

ndation for information security across the federal government, including a structure , yet flexible approach for managing information security risk across an organization. In 2012, this collaboration produced foundational guidelines for conducting risk assessments, and - updated guidelines for selecting and specifying security controls for federal information systems and organizations; - “ Provided assistance to agencies and the private sector: conducted ongoing, substantial reimbursable and non-reimbursable assistance to the government and private sector , including many outreach efforts through the Federal Information Systems Security Educators' Association (FISSEA), the Federal Computer Security Program Managers' Forum, and the Small Business Information Security Corner; - “ Reviewe security policies an technologies from the private sector and national security systems for potential federal agency use: hosted a repository of federal agency security practices, public/private security practices, an security configuration checklists for IT pro ucts. Continue to lea , in conjunction with the Government of Canada's Communications Security Establishment, the Cryptographic Module Validation Program (CMVP).

(Response) In the PRIA, we assumed that persons subject to this final rule may be required to add a limited amount of new information to existing transactions records, such as bills of lading, commercial invoices, and other shipping documents. We did not model the costs of compliance for each sector in the food economy, and assumed that the private incentives to maintain most, if not all, of the required information were sufficient. Examples of private incentives to maintain the required records are provided in our response to comment 189. Moreover, we do not require that the information be in any particular form or format, which further reduces the potential costs of compliance. c. Pet foods sector . (Comment 210) Some comments suggest that FDA eliminate requirements for pet food because the risk of exposure through that sector is small. Other comments acknowledge potential targets and impacts from terrorist attacks through the pet food sector and encourage FDA to require all in the pet food sector to be subject to the final rule. (Response) In the proposed rule, pet food not subject to the BSE rule was excluded from the requirement to establish and maintain records. In this final rule, all animal feed entities, including all pet food entities, are subject to all requirements of the rule, but have a records retention requirement of 1 year. There are approximately 19,600 facilities that were excluded in the proposed rule and that have been included in this final rule. In the PRIA, rather than estimate the cost savings from excluding these facilities from complying with the regulation, we noted that the costs were overestimated because pet food facilities were included in the estimates. In the final rule, pet food entities are subject to the regulation and are included in the cost estimates. d. Food contact substances and the packaging sector . (Comment 211) FDA received many comments that FDA underestimated the number of facilities covered by the definition of substances and components of substances that contact food. One comment states that FDA does not include the ‘upstream’ manufacturers that make ingredients and components that go into food packaging who would be required to comply with the recordkeeping provisions of this regulation. The comment further states that there is no logical conclusion to this chain. Some other comments assert that FDA did not account for warehouses that hold articles that can migrate to food from food packaging, or other articles that contact food. Another comment states that FDA's count of the number of domestic facilities is overly inclusive if FDA's intention is to include only finished packaging and that the Operational and Administrative System for Import Support (OASIS) database used for the count of foreign facilities does not include suppliers of food contact articles. Other comments indicate that FDA understated the number of (printed page 71640)

According to NIST_SP_800-37r2_Risk_Management_Framework, Executive Summary: by the Defense Science Board, the Executive Order, and the OMB policy memorandum to develop the nextgeneration Risk Management Framework (RMF) for information systems, organizations, and individuals. There are seven major objectives for this update: - To provide closer linkage and communication between the risk management processes and activities at the C-suite or governance level of the organization and the individuals, processes, and activities at the system and operational level of the organization; - To institutionalize critical risk management preparatory activities at all risk management levels to facilitate a more effective, efficient, and cost-effective execution of the RMF; - To demonstrate how the NIST Cybersecurity Framework [NIST CSF] can be aligned with the RMF and implemented using established NIST risk management processes; - To integrate privacy risk management processes into the RMF to better support the privacy protection needs for which privacy programs are responsible; - To promote the development of trustworthy secure software and systems by aligning life cycle-based systems engineering processes in NIST Special Publication 800-160, Volume 1 [SP 800-160 v1], with the relevant tasks in the RMF; - To integrate security-related, supply chain risk management (SCRM)

concepts into the RMF to address untrustworthy suppliers, insertion of counterfeits, tampering, unauthorized production, theft, insertion of malicious code, and poor manufacturing and development practices throughout the SDLC; and - To allow for an organization-generated control selection approach to complement the traditional baseline control selection approach and support the use of the consolidated control catalog in NIST Special Publication 800-53, Revision 5. The addition of the Prepare step is one of the key changes to the RMF-incorporated to achieve more effective, efficient, and cost-effective security and privacy risk management processes.

C3PAO engagement inclusive of Phases 1, 2, and 3 (3-person team) for 120 hours (\$260.28/hr × 120hrs = \$31,234) Reaffirmations: It is estimated that the costs to reaffirm a Level 2 certification assessment annually is \$1,459 (three-year cost is \$4,377, or \$1,459 × 3) A director (MGMT5) for 4 hours (\$190.52/hr × 4hrs = \$762) A staff IT specialist (IT4-SB) for 8.08 hours (\$86.24/hr × 8.08hrs = \$697) The Level 2 affirmations cost burden will be addressed as part of the 48 CFR part 204 CMMC Acquisition rule. Summary: The following is the annual small entities total cost summary for Level 2 certification assessments and affirmations over a ten-year period: (Example calculation, Year 2: (*\$101,752 assessment per entity × 1,926 entities) + (\$1,459 annual affirmation per entity × 382 entities) = \$196,531,451) All Entities Summary The following is a summary of the cost to all entities regardless of size for Level 2 certification assessment and affirmation costs over a ten-year period: (printed page 83187) CMMC Level 3 Certification Assessment and Affirmation Costs An OSC pursuing Level 3 certification assessment must have a CMMC Status of Final Level 2 (C3PAO), and also must demonstrate compliance with CMMC Level 3, which includes implementation of selected security requirements from NIST SP 800-172 Feb2021 not required in prior rules. Therefore, the Nonrecurring Engineering and Recurring Engineering cost estimates have been included for the initial implementation and maintenance of the required selected NIST SP 800-172 Feb2021 security requirements. The cost estimates account for time for an OSC to implement these security requirements and prepare for, support, participate in, and closeout a Level 3 certification assessment conducted by DCMA DIBCAC. The OSC should keep in mind that the total cost of a Level 3 certification assessment includes the cost of a Level 2 certification assessment as well as the costs to implement and assess the security requirements specific to Level 3. CMMC Level 3 is expected to affect a small subset of the DIB. Other Than Small Entities, per Entity Nonrecurring Engineering Costs: \$21,100,000. [49] Recurring Engineering Costs: \$4,120,000. Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a Level 3 certification assessment and affirmation for an other than small entity is *\$39,021. The three-year cost is \$44,445 (as summarized in 4.1.2, table 23), and includes the triennial assessment + affirmation, plus two additional annual affirmations (\$39,021 + \$2,712 + \$2,712). Phase 1: Planning and preparing for the certification assessment: \$7,066 A director (MGMT5) for 12 hours (\$190.52/hr × 12hrs = \$2,286) A manager (MGMT2) for 12 hours (\$95.96/hr × 12hrs = \$1,152) A staff IT specialist (IT4) for 16 hours (\$97.49/hr × 16hrs = \$1,560) A senior IT specialist (IT3) for 12 hours (\$81.96/hr × 12hrs = \$984) An IT specialist (IT2) for 20 hours (\$54.27/hr × 20hrs = \$1,085) Phase 2: Conducting the certification assessment: \$23,136

- 4) map communications between the security zones - 5) determine security controls for the security zones - 6) create a logical security architecture diagram Security zone-based architecture provides a standardized way of designing a scalable and consistent security architecture. It offers increased network resiliency, meaning it helps keep communications working in the face of misconfiguration and faults. Security segmentation can help mitigate the vulnerabilities listed above and should be part of a comprehensive cybersecurity plan. The fundamental building blocks of security segmentation are security zones, security controls, and trusted communications. Each is explained in turn, below.

. (1) A DoD contract for performance of services and/or delivery of supplies in an area of contingency operations outside the United States or a contract of a non-DoD Federal agency for performance of services and/or delivery of supplies in an area of combat operations or other significant military operations, as designated by the Secretary of Defense; a subcontract at any tier under such a contract; or a task order or delivery order issued under such a contract or subcontract. (2) Also includes contracts or subcontracts funded under grants and sub-grants by a Federal agency for performance in an area of combat operations or other significant military operations as designated by the Secretary of Defense. (3) Excludes temporary arrangements entered into by non-DoD contractors or grantees for the performance of private security functions by individual indigenous personnel not affiliated with a local or expatriate security company. Such arrangements must still be in compliance with local law. Other significant military operations.

For purposes of this part, the term 'other significant military operations' means activities, other than combat operations, as part of an overseas contingency operation that are carried out by United States Armed Forces in an uncontrolled or unpredictable high-threat environment where personnel performing security functions may be called upon to use deadly force. [1] Private security functions . Activities engaged in by a contractor under a covered contract as follows: (1) Guarding of personnel, facilities, designated sites, or property of a Federal agency, the contractor or subcontractor, or a third party. [2] (2) Any other activity for which personnel are required to carry weapons in the performance of their duties in accordance with the terms of their contract. For the DoD, DoDI Instruction 3020.41, 'Contractor Personnel Authorized to Accompany the U.S. Armed Forces,' [3] prescribes policies related to personnel allowed to carry weapons for self defense. PSC . During contingency operations 'PSC' means a company employed by the DoD performing private security functions under a covered contract. In a designated area of combat operations or other significant military operations, the term 'PSC' expands to include all companies employed by U.S.G. agencies performing private security functions under a covered contract. PSC personnel . Any individual performing private security functions under a covered contract. § 159.4 Policy. (a) Consistent with the requirements of paragraph (a)(2) of section 862 of Public Law 110-181

3.8.1 | The Audit Organization | The Audit Organization | 65 | | 3. 3.8.1 The Audit Organization
The NBS/PCIE workshop attendees came up with a number of recommendations for further activity by ADP Audit/Computer Security Organizations.

3.3.4 Trade Literature/Publications/Electronic News In addition to monitoring the system, it is useful to monitor external sources for information.

Rural health care providers are more likely to have limited resources to update legacy information technology (IT) systems, implement new or changed regulatory requirements, and respond to large breaches. Additionally, the health IT workforce is more limited in rural areas, which may affect the ability of rural health care providers to access in-person technical assistance. Because most rural hospitals are 'located more than 35 miles from another hospital,' responding to cyberattacks may be more challenging. [1017] We request comment on the burdens these proposals would impose on rural health care providers, including rural hospitals. Rural health care providers and other regulated entities can avail themselves of grants and incentives to improve broadband access and adoption of health IT. [1018] For cybersecurity in particular, the White House, in partnership with private companies, announced the availability of direct assistance to rural health care providers on cybersecurity in the form of grants, discounts, and technical advice. [1019] Additionally, CISA has compiled a list of free services and tools available to regulated entities from private and public sector entities. CISA also has published, in partnership with the Joint Cyber Defense Collaborative, a list of cybersecurity resources especially focused on high-risk communities. [1020] And the Advanced Research Projects Agency for Health announced plans to invest \$50 million to develop an autonomous solution for addressing cyberthreats to assist hospitals in defending their information systems. [1021] Cybersecurity is as essential for small and rural health care providers and their business associates, as it is for large and urban regulated entities. The seamless flow of data and increased connectivity means that threats to one health care provider do not affect only that one health care provider, regardless of size or location. The effects on patient care may be greater in rural environments where fewer alternatives exist if care is delayed or denied as a result of a cyberattack or malfunction. [1022] As discussed in the preamble, the factors described at 45 CFR 164.306(b)(2) provide the flexibility for small and rural providers, in particular, to adopt security measures that are reasonable and appropriate for their circumstances. D. Executive Order 13132 'Federalism As required by E.O. 13132 on Federalism, [1023] the Department has examined the provisions in the proposed regulation for their effects on the relationship between the Federal Government and the States. E.O. 13132 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct requirement costs on State and local governments, preempts State law, or otherwise has federalism implications. In the Department's view, the proposed rule would not have any federalism implications. The federalism implications of the Security Rule were also assessed as required by

This proposed rule will impact small businesses awarded a contract to develop, implement, operate, or maintain a FIS on behalf of the Government. The Government acknowledges that large businesses

awarded a contract for such services may further subcontract some of the services that are subject to the requirements of the clauses. As such, the Government estimates that up to an additional seven small business entities may receive a subcontract to develop, implement, operate, or maintain a FIS under a prime contract for the same services. The responsibilities prescribed to contractors under this rule apply per FIS, not per contractor or subcontractor. Multiple entities will not be responsible for implementing or executing the same requirement for the same FIS; As such, the Government describes the impact of this rule on small business under the assumption that each of the responsibilities described below will be subcontracted to a small business at least once annually. According to subject matter experts, there are approximately 140 non-cloud FISs currently being operated or maintained by contractors on behalf of the Government. The Government estimates it awards 28 contracts ((20 percent * 140 non-cloud FISs) * 1 contract/FIS) to 28 unique contractors (28 contracts = 28 unique entities) annually for the development, implementation, operation, or maintenance of a non-cloud FIS on behalf of the Government. Of the 28 contractors to be awarded a contract each year to operate or maintain a non-cloud FIS, approximately three (28 contractors * 10 percent) are small businesses. According to FedRAMP data and subject matter experts, there are approximately 280 unique FedRAMP-authorized and ready cloud service offerings available to the Federal Government. Based on the number of FedRAMP-authorized offerings, the Government estimates that there are approximately 56 new or revised FIS offerings (20 percent * 280 cloud service offerings) each year for which the Government contracts. Therefore, the Government estimates that 56 unique entities to be awarded a contract annually for the development, implementation, operation, or maintenance of a cloud FIS on behalf of the Government, of which approximately three (56 contractors * five percent) are small businesses. The proposed rule requires contractors awarded a contract or subcontract to develop, implement, operate, or maintain a FIS to read and become familiar with the rule, as well as review the applicable standards documents identified in the rule. The proposed rule also requires contractors awarded a contract or subcontract to develop, implement, operate, or maintain a FIS using other than cloud computing services (i.e.,

, respectively), the Department proposes several changes that would recognize the increasingly mobile nature of ePHI and workstations that connect to the information systems of regulated entities. The purpose of these proposals is to ensure that regulated entities properly consider physical safeguards for all workstations, including those that are mobile, and not only those that are located in regulated entities' facilities. The Department also proposes to modify both standards to clarify the organization of the regulatory text. The Department proposes to modify the standard for workstation use to clarify that policies and procedures established by a regulated entity to govern the use of workstations be in writing and address all workstations that access ePHI or the regulated entity's relevant electronic information systems. These proposed changes are consistent with the Department's longstanding expectations and other proposals in this NPRM described above. In 45 CFR 164.310(b)(2)(i)(C) , the Department proposes to require a regulated entity to establish and implement written policies and procedures that, among other things, specify the physical attributes of workstation surroundings, including the removal of workstations from a facility and the movement of workstations within and outside of a facility. This proposal is consistent with (printed page 961) the proposed revision to the definition of ·workstation· discussed above. Additionally, we propose to add an implementation specification for maintenance at proposed 45 CFR 164.310(b)(2)(ii) to require that a regulated entity review and test its written policies and procedures at least once every 12 months, and to modify those policies and procedures as reasonable and appropriate based on that review. Relatedly, the Department proposes to modify the standard for workstation security at 45 CFR 164.310(c) to require a regulated entity to implement physical safeguards for workstations that access ePHI or relevant electronic information systems to comply with its written policies and procedures for workstation use. This proposal would also make clear that such physical safeguards must be modified in response to any modifications to the written policies and procedures for workstation use. As part of their policies and procedures for workstation security, the Department encourages regulated entities to consider, among other things, whether there are workstations located in public areas or other areas that are more vulnerable to theft, unauthorized use, or unauthorized viewing; whether such devices should be relocated; the physical security controls for workstations that are in use (e.g., cable locks, privacy screens, secured rooms, cameras) and whether they are easy to use; and whether there are additional physical security controls that could reasonably be put into place. [648]

www.mitre.org/sites/default/files/publications/pr-18-2417-deliver-uncompromised-MITRE-study-26AUG2019.pdf . Back to Citation 35. www.cisa.gov/uscert/ncas/alerts/aa22-057a . Back to Citation 36. ·DODIG-2019-105 ·Audit of Protection of DoD CUI on Contractor-Owned Networks and Systems.· Back to Citation 37. ·The number of unique awardees impacted each year is 1/3 of the average number of annual awardees according to the Electronic Data Access system (31,338/3 = 10,446). This estimate does not address new entrants or awardees who discontinue doing business with DoD. Back to Citation 38. ·Includes all businesses with the exception of those defined under the small business criteria and size standards provided in 13 CFR 121.201 (See FAR Part 19.102) Back to Citation 39. ·The Level I self-assessment and Level 2 self- assessment information collection reporting and recordkeeping requirements will be included in a modification of an existing DFARS collection approved under OBM Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Modifications to this DFARS collection will be addressed as part of the 48 CFR part 204 CMMC Acquisition rule. 40. ·The Level 1 self-assessment and Level 2 self-assessment information collection reporting and recordkeeping requirements will be included in a modification of an existing DFARS collection approved under OBM Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Modifications to this DFARS collection will be addressed as part of the 48 CFR part 204 CMMC Acquisition rule. Back to Citation 41. ·The terms nonrecurring engineering costs and recurring engineering costs are terms of art and do not only encompass actual engineering costs. Back to Citation 42. ·IT = Information Technology, MGMT = Management. 43. ·IT and MGMT rates represent an estimate for in-house labor and includes the labor rate plus fringe and employee-related expenses. 44. ·Background assumes a Bachelor's degree as the minimum education level, additional requirements are noted including required years of experience. A Master's degree may reduce the required years of experience as noted. 45. ·The ESP/C3PAO rate represents an estimate for outsourced labor and includes the labor rate, overhead expense, G&A expense, and profit. Back to Citation 46. ·CMMC Level 1 consists of the same 15 basic safeguarding requirements specified in FAR clause 52.204-21. This cost analysis assumes that defense contractors and subcontractors already have contracts with FAR clause 52.204-21 and, therefore, have already implemented the 15 basic safeguarding requirements. Back to Citation 47. ·Again, it is assumed that that defense contractors and subcontractors have already implemented the 15 basic safeguarding requirements in FAR clause 52.204-21.

We believe these obligations would be clarified by the proposals in this NPRM. For example, the Department proposes to require that a regulated entity not only conduct an accurate assessment of potential risks and vulnerabilities to the confidentiality, integrity, and availability of the ePHI it creates, receives, maintains, or transmits, but would add an express requirement that the assessment be comprehensive and in writing. We also propose to specify that the required assessment include, among other things, identification of all reasonably anticipated threats and potential vulnerabilities and predisposing conditions, making a reasonable determination and documentation of the likelihood that each identified threat will exploit the identified vulnerabilities, and performing a written assessment of the risk level for each identified threat and vulnerability. Under the NPRM, a regulated entity would be expected to, as part of the risk analysis, consider whether quantum computing poses a reasonably anticipated threat to the confidentiality, integrity, or availability of its ePHI and whether there is a vulnerability or predisposing condition that corresponds to that threat, and to document those considerations; make a reasonable determination and document the likelihood that the threat will exploit the identified vulnerabilities; and assign a risk level to the identified threat and vulnerability.

2. Artificial Intelligence (AI) Section 238(g) of the John S. McCain National Defense Authorization Act for Fiscal Year 2019 defined AI to include the following: [892] Any artificial system that performs tasks under varying and unpredictable circumstances without significant human oversight, or that can learn from experience and improve performance when exposed to data sets. An artificial system developed in computer software, physical hardware, or other context that solves tasks requiring human-like perception, (printed page 990) cognition, planning, learning, communication, or physical action. An artificial system designed to think or act like a human, including cognitive architectures and neural networks. A set of techniques, including machine learning, that is designed to approximate a cognitive task. An artificial system designed to act rationally, including an intelligent software agent or embodied robot that achieves goals using perception, planning, reasoning, learning, communicating, decision making, and acting. AI requires enormous amounts of data to develop, but it also has enormous potential benefits. The Department has previously stated that these technologies have the potential to drive innovation, increase market competition, and vastly improve care for patients and

populations. [893] According to experts, "[. . .]AI is unlocking new possibilities by advancing medicine in entirely unimaginable ways and solving some of the grand global healthcare challenges. [894]

verify, or state) under penalty of perjury that the foregoing is true and correct. Executed on (date). (Signature). (ii) If executed outside of the United States: I declare under perjury or penalty under the laws of the United States of America that the foregoing is true and correct. Executed on (date). (Signature). (3) When an individual seeks access in person, identification can be verified by documents normally carried by the individual (such as identification card, driver's license, or other license, permit or pass normally used for identification purposes). However, level of proof of identity is commensurate with the sensitivity of the records sought. For example, more proof is required to access medical records than is required to access parking records. (4) Telephonic requests will not be honored. (5) An individual cannot be denied access solely for refusal to provide his or her Social Security Number (SSN) unless the SSN was required for access by statute or regulation adopted prior to January 1, 1975. (6) If an individual wishes to have his or her records released directly to a third party or to be accompanied by a third party when seeking access to his or her records, reasonable proof of authorization must be obtained. The individual may be required to furnish a signed access authorization with a notarized signature or other proof of authenticity (i.e. telephonic confirmation) before granting the third party access. (d) Individual access to medical records. (1) An individual must be given access to his or her medical and psychological records unless a judgment is made that access to such records could have an adverse effect on the mental or physical health of the individual. This determination normally should be made in consultation with a medical doctor. Additional guidance is provided in DOD 5400.11-R, Department of Defense Privacy Program. In this instance, the individual will be asked to provide the name of a personal health care provider, and the records will be provided to that health care provider, along with an explanation of why access without medical supervision could be harmful to the individual. (2) Information that may be harmful to the record subject should not be released to a designated individual unless the designee is qualified to make psychiatric or medical determinations. (3) DA activities may offer the services of a military physician, other than the one who provided the treatment. (4) Do not require the named health care provider to request the records for the individual. (5) The agency's decision to furnish the records to a medical designee and not directly to the individual is not considered a denial for reporting purposes under the Act and cannot be appealed. (6) However, no matter what the special procedures are, DA has a statutory obligation to ensure that access is provided the individual.

5. Maintenance Agency. 1 An information system is a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information. Information resources include information and related resources, such as personnel, equipment, funds, and information technology. The minimum security requirements cover seventeen security-related areas with regard to protecting the confidentiality, integrity, and availability of federal information systems and the information processed, stored, and transmitted by those systems. The security-related areas include: (i) access control; (ii) awareness and training; (iii) audit and accountability; (iv) certification, accreditation, and security assessments; (v) configuration management; (vi) contingency planning; (vii) identification and authentication; (viii) incident response; (ix) maintenance; (x) media protection; (xi) physical and environmental protection; (xii) planning; (xiii) personnel security; (xiv) risk assessment; (xv) systems and services acquisition; (xvi) system and communications protection; and (xvii) system and information integrity. The seventeen areas represent a broad-based, balanced information security program that addresses the management, operational, and technical aspects of protecting federal information and information systems.

HIPAA Security Rule section 164.314 (Organizational Requirements) addresses business associate contracts. Covered entities and business associates must implement appropriate safeguards to protect electronic protected health information (ePHI). For business associate contracts, organizations should: 1. Establish and document policies specific to business associate contracts 2. Implement technical and procedural controls 3. Train workforce members on their responsibilities 4. Conduct periodic risk assessments addressing business associate contracts 5. Maintain documentation of compliance efforts Under 45 CFR 164.314, this is an organizational requirements requirement that applies to all covered entities and business associates that create, receive, maintain, or transmit ePHI.

2. SP 800-30, Risk Management Guide for Information Technology Systems; 3. SP 800-53A, Guide for Assessing the Security Controls in Federal Information Systems, and 800-53A Revision 1, Guide for Assessing the Security Controls in Federal Information Systems and Organizations, Building Effective Security Assessment Plans; 4. SP 800-77, Guide to IPsec VPNs; 5. SP 800-115, Technical Guide to Information Security Testing and Assessment; 6. SP 800-34, Contingency Planning Guide for Federal Information Systems; 7. SP 800-94, Guide to Intrusion Detection and Prevention Systems (IDPS); 8. FIPS 140-2, Security Requirements for Cryptographic Modules; 9. SP 800-100, Information Security Handbook: A Guide for Managers; and 10. NISTIR 7628, Guidelines for Smart Grid Cyber Security. We also invite public and private organizations to submit their information security practices to be considered for inclusion on the website. Policies and procedures may be submitted to us in any area of information security, such as accreditation, audit trails, authorization of processing, budget planning and justification, certification, contingency planning, data integrity, disaster planning, documentation, hardware and system maintenance, identification and authentication, incident handling and response, life cycle, network security, personnel security, physical and environmental protection, production input/output controls, security policy, program management, review of security controls, risk management, security awareness training and education (including specific training course and awareness materials), and security planning.

Control RC-32: in), Lecture Notes in Computer Science 6715, pp. 345-358. - [78] Thompson A, Taylor BN (2008) Guide for the Use of the International System of Units (SI). (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 811. <https://doi.org/10.6028/NIST.SP.811e2008> - [79] Turan MS, Barker E, Kelsey J, McKay KA, Baish ML, Boyle M (2018) Recommendation for the Entropy Sources Used for Random Bit Generation. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-90B. <https://doi.org/10.6028/NIST.SP.800-90B> - [80] Van Houtven L (2020) Crypto 101. Available at <https://www.crypto101.io/Crypto101.pdf> - [81] Vaudenay S (2002) Security Flaws Induced by CBC Padding - Applications to SSL, IPSEC, WTLS... Advances in Cryptology (EUROCRYPT 2002), ed Knudsen LR (Springer, Amsterdam, The Netherlands), Lecture Notes in Computer Science 2332, pp. 534-545, - [82] 'Definitions,' Title 44 U.S. Code, Sec. 3542. 2013 ed. <https://www.govinfo.gov/app/details/USCODE-2013-title44/USCODE-2013-title44chap35-subchapIII-sec3542> ## Appendix A.

accordance with title 5 CFR 1400.201(b) and (d) and the investigative requirements of title 5 CFR 731.106(c)(2). (4) Meet the equivalent of a favorably adjudicated Tier 3 background investigation when not eligible for a Tier 3 background investigation. DoD will determine the Tier 3 background investigation equivalence for use with the CMMC Program only. (5) Provide all documentation and records in English. (6) Be a CCP who has at least 3 years of cybersecurity experience, 1 year of assessment or audit experience, and at least one baseline certification aligned to either paragraph (b)(6)(i) or (ii) of this section through 15 February 2025 and aligned to paragraph (b)(6)(ii) of this section only beginning 16 February 2025. (i) IAT Level II from DoD Manual 8570 Information Assurance Workforce Improvement Program. (ii) Intermediate Proficiency Level for Career Pathway Certified Assessor 612 from DoD Manual 8140.03 Cyberspace Workforce Qualification & Management Program. (7) Qualify as a Lead CCA by having at least 5 years of cybersecurity experience, 5 years of management experience, 3 years of assessment or audit experience, and at least one baseline certification aligned to either paragraph (b)(7)(i) or (ii) of this section through 15 February 2025 and aligned to paragraph (b)(7)(ii) of this section only beginning 16 February 2025. (i) IAM Level II from DoD Manual 8570 Information Assurance Workforce Improvement Program. (ii) Advanced Proficiency Level for Career Pathway Certified Assessor 612 from DoD Manual 8140.03 Cyberspace Workforce Qualification & Management Program. (8) Only use IT, cloud, cybersecurity services, and end-point devices provided by the authorized/accredited C3PAO that they support and has received a CMMC Level 2 Certification Assessment or higher for all assessment activities. Individual assessors are prohibited from using any other IT, including IT that is personally owned, to include internal and external cloud services and end-point devices, to store, process, handle, or transmit CMMC assessment reports or any other CMMC assessment-related information. (9) Immediately notify the responsible C3PAO of any breach or potential breach of security to any CMMC-related assessment materials under the assessors' purview. (10) Not share any CMMC assessment-related outcomes or advance information with any person not assigned to that specific assessment, except as otherwise required by law. § 170.12 CMMC Certified Instructor (CCI). (a) Roles and responsibilities. A CMMC Certified Instructor (CCI) teaches CMMC assessor candidates. A CCI is trained, tested, and

certified to perform CMMC instructional duties by the CAICO to teach CMMC assessor candidates. Candidate CCIs are certified by the CAICO after successful completion of the CCI training and testing requirements set forth in paragraph (b) of this section. (b) Requirements. CCIs shall:

Purpose The purpose of the Implement step is to implement the controls in the security and privacy plans for the system and for the organization and to document in a baseline configuration, the specific details of the control implementation. NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

CHAPTER THREE PAGE 59 This publication is available free of charge from:

<https://doi.org/10.6028/NIST.SP.800-37r2> System Development Life Cycle Phase: New · Development/Acquisition; Implementation/Assessment. Existing · Operations/Maintenance. Discussion: Organizations implement the controls as described in the security and privacy plans. The control implementation is consistent with the organization's enterprise architecture and associated security and privacy architectures. Organizations use best practices when implementing controls, including systems security and privacy engineering methodologies, concepts, and principles. Risk assessments guide and inform decisions regarding the cost, benefit, and risk trade-offs in using different technologies or policies for control implementation. Organizations also ensure that mandatory configuration settings are established and implemented on system elements in accordance with federal and organizational policies. When organizations have no direct control over what controls are implemented in a system element, for example, in commercial off-the-shelf products, organizations consider the use of system elements that have been tested, evaluated, or validated by approved, independent, third-party assessment facilities (e.g., NIST Cryptographic Module Validation Program Testing Laboratories, National Information Assurance Partnership Common Criteria Testing Laboratories). The tests, evaluations, and validations consider products in specific configurations and in isolation; control implementation addresses how the product is integrated into the system while preserving security functionality and assurance. Organizations also address, where applicable, assurance requirements when implementing controls. Assurance requirements are directed at the activities that control developers and implementers carry out to increase the level of confidence that the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security and privacy requirements for the system. The assurance requirements address quality of the design, development, and implementation of the controls.⁸⁵ For the common controls inherited by the system, systems security and privacy engineers with support from system security and privacy officers, coordinate with the common control provider to determine the most appropriate way to implement common controls. System owners can refer to the authorization packages prepared by common control providers when making determinations regarding the adequacy of common controls inherited by their systems. During implementation, it may be determined that common controls previously selected to be inherited by the system do not meet the specified security or privacy requirements for the system. For common controls that do not meet the requirements for the system inheriting the controls or when common controls have unacceptable deficiencies, the system owners identify compensating or supplementary controls to be implemented. System owners can supplement the common controls with system-specific or hybrid controls to achieve the required protection for their systems or they can accept greater risk with the acknowledgement and approval of the organization. Risk assessments may determine how gaps in security or privacy requirements between systems and common controls affect the risk associated with the system, and how to prioritize the need for compensating or supplementary controls to mitigate specific risks. Consistent with the flexibility allowed in applying the tasks in the RMF, organizations conduct initial control assessments during system development and implementation. Conducting such assessments in parallel with the development and implementation phases of the SDLC facilitates early identification of deficiencies and provides a cost-effective method for initiating corrective actions. Issues discovered during these assessments can be referred to authorizing officials for resolution. The results of the initial control assessments can also be used during the authorize step to avoid delays or costly repetition of assessments. Assessment results that are subsequently reused in other phases of the SDLC meet the reuse requirements established by the organization.⁸⁶ ⁸⁵ [SP 800-53] provides a list of assurance-related security and privacy controls. ⁸⁶ See the RMF Assess step and [SP 800-53A] for information on assessments and reuse of assessment results.

65. A person needs to enter the information into SPRS, which should only take five minutes.

Back to Citation 66. ·An Organization Seeking Certification (OSC) is an entity seeking to contract, obtain, or maintain CMMC certification for a given information system at a particular CMMC Level. An OSC is also an OSA. Back to Citation 67. ·An Organization Seeking Assessment (OSA) is an entity seeking to conduct, obtain, or maintain a CMMC assessment for a given information system at a particular CMMC Level. The term OSA includes all OSCs. Back to Citation 68. ·Respondent is equivalent to an entity; an entity provides one response annually. 69. ·Hours per Response represents the estimated burden hours to complete the indicated assessment. 70. ·Hourly Rate represents a composite hourly rate derived from the detailed type of labor and associated rates estimated in the CMMC cost estimate model. 71. ·The entity type refers to the size of the OSC as either Small or Other Than Small; the entity type does not refer to the size of the C3PAO. Back to Citation 72. ·Respondent is equivalent to an entity; an entity provides one response annually. 73. ·Hours per Response represents the estimated Government burden hours to complete the indicated assessment. 74. ·The Hourly Rate represents a composite hourly rate derived from the detailed type of Government labor and associated rates estimated in the CMMC cost estimate model. 75. ·The entity type refers to the size of the OSC as either Small or Other Than Small; the entity type does not refer to the size of DCMA DIBCAC. Back to Citation [FR Doc. 2024-22905 Filed 10-11-24; 8:45 am] BILLING CODE 6001-FR-P

From the NIST SP 800-172 Rev 3 Final Public Draft: It also increases the likelihood of NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 detection. Defense-in-depth architectural approaches include modularity and 2459

Analysis || RS | Respond | RS.MI | Mitigation || RS | Respond | RS.IM | Improvements || RC | Recover | RC.RP | Recovery Planning || RC | Recover | RC.IM | Improvements || RC | Recover | RC.CO | Communications |

CIS Safeguard 13.1 · Centralize Security Event Alerting Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard. Implementation Groups: 2,3 Asset Type: network Security Function: detect Parent Control: Network Monitoring and Defense

According to Cryptographic Key Management Workshop Summary -- June 8-9, 2009, 2.4.4 Leap-Ahead Technologies: Miles Smid, Orion Security Solutions: per and lower air bags. Yes, we pay more for our cars, but we expect safety to be built in. There may also be smaller leaps in security that could help solve our cryptographic key management problems. What if we had the capability to automatically validate key establishment protocols or even use provably-secure protocols? Quantum cryptography could also improve security by permitting us to easily distribute secret values in a secure manner. But, there is more to key management than key establishment. Many key management problems involve the secure generation, storage, access and recovery of the keys, either before or after they are distributed. - Leaps in ease of implementation, management, and use: We have already made significant progress in this area. Electronic distribution of wrapped keys led to an improvement over manually distributed keys, and public key-based key distribution led to an improvement over key wrapping. Today, PKI, even with all of its problems, provides a major leap ahead over previously used systems. But, we still seem to be repeating some of the mistakes of the past. We build systems, we implement them, and then we find out that the users consider them unacceptable. We must not wait until the last minute to get the user's opinion. We need to build prototypes of a system and test them with real users before we extensively field the final product. - We need to explore the advantages of alternative approaches like identity-based key management. - What if we had cloud key management? By that I mean that I could go to some trusted part of the cloud and say, 'Please give me a key to communicate securely with jsmith@verizon.net.' Better yet would be if I could go to the trusted part of the cloud and say, 'Please give me a secure channel to jsmith@verizon.net.' Best of all would probably be if the security was provided by the cloud for all my communications. - I like a holistic approach to enterprise key management.

- (i) This includes CUI that the Government provides to the Contractor or CUI that the Contractor collects, develops, receives, transmits, uses, handles, or stores in performance of the contract.
- (ii) For CUI located within a Federally-controlled facility, the Contractor shall follow agency CUI policies and shall ensure that any Contractor employees handling CUI within Federally-controlled

facilities meet the prerequisites identified within Part B on the SF XXX for training and for access to CUI. (iii) For CUI located within a non-Federally-controlled facility, the Contractor shall follow CUI policies and shall ensure that any Contractor employees handling CUI within the non-Federally-controlled facility comply with the requirements identified in Part C of the SF XXX. (iv) Any applicable agency-specific policies for safeguarding or handling CUI will be identified in the SF XXX. (v) When information is not identified as CUI, it may be covered Federal information requiring information system security controls in accordance with Federal Acquisition Regulation clause 52.204-21, Basic Safeguarding of Covered Contractor Information Systems. (2) The Contractor shall permit access to CUI only as described in the SF XXX. (3) Except for its own information, the Contractor is not responsible for identifying or marking unmarked or mismarked CUI unless doing so is specifically included in the SF XXX, such as when the Contractor generates or develops the CUI. (4) No Contractor employee shall be permitted to have or retain access to, create, collect, use, process, store, maintain, disseminate, disclose, dispose of, or otherwise handle CUI unless the employee has completed training on properly handling CUI that, at a minimum, includes the elements required in the SF XXX. (5) Contractors operating information systems that access, use, process, store, maintain, or transmit CUI identified in the contract, shall implement the following requirements: (i) When the Contractor is operating an information system identified in the SF XXX as a Federal information system: (A) The Contractor shall comply with agency-identified security requirements from the latest version of National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53 and any CUI Specified requirements identified in the SF XXX; and (B) If using cloud computing services, the Contractor shall comply with agency-identified security requirements, but at no less than the Federal Risk and Authorization Management Program (FedRAMP) Moderate baseline (<https://www.fedramp.gov/documents/>). (ii) When the Contractor is operating a non-Federal information system, the Contractor shall: (A) Comply with the security requirements of NIST SP 800-171 Revision 2, Protecting Controlled Unclassified Information in Non-Federal Information Systems and Organizations (available via the internet at <https://dx.doi.org/10.6028/NIST.SP.800-171>

Many executives are not aware of the central role SSH keys play in the secure management and operation of mission critical infrastructure and the significant breaches that can occur if they are exploited. Without sufficient executive education for both security and operationally focused executives, SSH key management initiatives can get derailed by other seemingly higher priorities, leaving an organization vulnerable. To ensure the proper level of priority is placed on the implementing and sustaining SSH key management, it is important that executives understand the systems on which SSH is used, the levels of access granted to users and automated processes via SSH, the risks and potential impacts of an SSH-based breach (including pivoting), and the basic steps needed to implement an SSH key management program (as outlined in this document).

From the NIST SP 800-172 Rev 3 Final Public Draft: This includes approved CUI categories and category descriptions, the basis for safeguarding and dissemination controls, and procedures for the use of CUI. 2 Procedures for the use of CUI include marking, safeguarding, transporting, disseminating, reusing, and disposing of the information. The CUI federal regulation provides guidance to federal agencies on the designation, safeguarding, marking, dissemination, decontrolling, and disposition of CUI; establishes self-inspection and oversight requirements; and delineates other facets of the program. [5] The CUI regulation requires federal agencies that use federal information systems 3 A federal information system is a system that is used or operated by an executive agency, by a contractor of an executive agency, or by another organi

From the NIST SP 800-172 Rev 3 Final Public Draft: A condition that results from the establishment and maintenance of protective measures that enable an organization to perform its mission or critical functions despite risks posed by threats to its use of systems. Protective measures may involve a combination of deterrence, avoidance, prevention, detection, recovery, and correction that should form part of the organization's risk management approach. security assessment See security control assessment . security control The safeguards or countermeasures prescribed for an information system or an organization to protect the confidentiality, integrity, and availability of the system and its information. [18] security control assessment The testing or evaluation of security controls to determine the extent to which the contro

A director (MGMT5) for 8 hours (\$190.52/hr × 8hrs = \$1,524) A staff IT specialist (IT4-SB) for 48 hours (\$86.24/hr × 48hrs = \$345) Reaffirmations: It is estimated that the costs to reaffirm a CMMC

Level 3 Certification Assessment annually is \$1,876 (three-year cost is \$5,628, or \$1,876 × 3) A director (MGMT5) for 8 hours (\$190.52/hr × 8hrs = \$1,524) A staff IT specialist (IT4-SB) for 4.08 hours (\$86.24/hr × 4.08hrs = \$352) The Level 3 Affirmations cost burden will be addressed as part of the 48 CFR acquisition rule. Summary: The following is the annual small entities total cost summary for CMMC Level 3 Certifications and Affirmations over a ten-year period. Example calculation, Year 2 (reference per entity amounts shown): *(\$9,050 Certification per entity × 45 entities) + (\$1,876 Annual Affirmation per entity × 3 entities) = \$412,897, and \$121,500,000 Nonrecurring Engineering cost (\$2,700,000 per entity × 45 entities being certified), and \$23,520,000 Recurring Engineering cost (\$490,000 per entity × 45 entities being certified) + (\$490,000 per entity × 3 entities performing affirmations) \$145,432,897 Total Cost = Certification and Affirmation Cost (\$412,897) + Nonrecurring Engineering cost (\$121,500,000) + Recurring Engineering cost (\$23,520,000), or \$145,432,897. (printed page 89098) All Entities Summary The following is a summary of the cost to all entities regardless of size for Level 3 CMMC Certification Assessments and affirmations over a ten-year period: (printed page 89099) Government Costs Summary of Impact The following is a summary of the estimated Government costs calculated for a 20-year horizon in 2023 dollars at a 7 percent and 3 percent discount rate. The Government costs include conducting Level 3 Certification Assessments, uploading results into the CMMC instantiation of eMASS, and the CMMC PMO costs. Government Costs (All Levels) The estimated Government costs utilize the entity numbers and phased roll-out detailed in the Public cost section. The DIBCAC estimated the detailed hours for all activities and other costs in a manner similar to the details shown in the Public cost section. Labor efforts for the Government are focused in Level 3. For purposes of the cost estimate, Government labor is based on the average of step one, five, and ten for GS-11 through GS-15 labor elements for the Washington, DC area. The cost of labor was increased by a factor of approximately 51 percent which includes an estimated fringe factor (fringe factor includes estimated average insurance and pension benefits) plus overhead (overhead factor represents supervision and management of the labor) to arrive at the estimated labor rates. The Government labor in this estimate is performed by DCMA, which is a labor-intensive agency with limited overhead expenses. Therefore, the overall added factor of 51 percent is appropriate versus a typical full overhead factor of 100 percent. CMMC Database Infrastructure Costs

· Assets that are in the Level 3 CMMC Assessment Scope Controlled Unclassified Information (CUI) Assets · Assets that process, store, or transmit CUI · Assets that can, but are not intended to, process, store, or transmit CUI (defined as Contractor Risk Managed Assets in Table 2 to paragraph (c)(1) of this section CMMC Scoping). · Document in the asset inventory · Document in the System Security Plan (SSP). · Document in the network diagram of the CMMC Assessment Scope. · Prepare to be assessed against CMMC security requirements. · Assess against all CMMC security requirements. (printed page 89135) Security Protection Assets · Assets that provide security functions or capabilities to the OSC's CMMC Assessment Scope, irrespective of whether or not these assets process, store, or transmit CUI · Document in the asset inventory · Document in the System Security Plan (SSP). · Document in the network diagram of the CMMC Assessment Scope. · Prepare to be assessed against CMMC security requirements. · Assess against all CMMC security requirements. Specialized Assets · Assets that can process, store, or transmit CUI but are unable to be fully secured, including: Internet of Things (IoT) devices, Industrial Internet of Things (IIoT) devices, Operational Technology (OT), Government Furnished Equipment (GFE), Restricted Information Systems, and Test Equipment · Document in the asset inventory · Document in the System Security Plan (SSP). · Document in the network diagram of the CMMC Assessment Scope. · Prepare to be assessed against CMMC security requirements. · Assess against all CMMC security requirements. · Intermediary devices are permitted to provide the capability for the specialized asset to meet one or more CMMC security requirements. · Assets that are not in the Level 3 CMMC Assessment Scope Out-of-Scope Assets · Assets that cannot process, store, or transmit CUI; and do not provide security protections for CUI Assets · Assets that are physically or logically separated from CUI assets. · Assets that fall into any in-scope asset category cannot be considered an Out-of-Scope Asset. · Prepare to justify the inability of an Out-of-Scope Asset to store, process, or transmit CUI · None. (2) If the organization seeking CMMC Level 3 Certification Assessment utilizes an ESP, other than a CSP, the ESP must also have a CMMC Level 3 Final Certification Assessment. If the ESP is internal to the OSC, the security requirements implemented by the ESP should be listed in the OSC's SSP to show connection to its in-scope environment. If using a CSP, see § 170.18(c)(5). In the CMMC Program, CUI or Security Protection Data (e.g., log data, configuration data), must be processed, stored, or transmitted on the ESP assets to be considered an ESP. (e) Relationship between Level 2 and Level 3 CMMC Assessment Scope. The Level 3 CMMC Assessment Scope must be equal to or a subset

of the Level 2 CMMC Assessment Scope in accordance with § 170.18(a), e.g.,

(Comment 141) Several comments offer suggestions on where the required records should be maintained. One comment recommends that, for intracorporate transfers, companies should be permitted to make all required records accessible at one location. The comment states that this would not delay, and could even enhance, efficiencies in an FDA traceback investigation. Several comments state that companies should have flexibility for determining where to maintain the required records. The comments note that it should be sufficient that the records are maintained and are accessible at some location, including the headquarters office for specific locations within a company. One comment requests clarification on whether records may be stored in separate locations, as long as the combined records adequately provide the required information. The comment notes that confidentiality requirements may cause records that contain part of the required information to be maintained in different locations. One comment states that, in the context of air transportation of food, the location where the activity occurred may be difficult to determine, and may not be a feasible place to store records or to make them available to FDA at a future date. According to the comment, the option to store records offsite, combined with the flexibility to maintain records in an electronic format, is critical to ensuring prompt access to the records. (Response) FDA requires in the final rule that the required records must be retained at the establishment where the covered activities described in the records occurred (onsite) or at a reasonably accessible location. The agency clarifies that the intent of this provision of the regulation is to provide flexibility for a company to determine the most efficient and readily accessible means of storage, consistent with the company's business practices. Access to the records may be provided to FDA electronically, by facsimile, or by other appropriate means consistent with the availability requirements in § 1.361 of this final rule, once FDA makes a written request under section 414(a) or 704(a) of the FD&C Act. Each individual company may determine the appropriate location for maintaining the required records and for ensuring that the record availability requirements can be met. L. Comments on What Are the Record Availability Requirements? (Proposed § 1.361)

3.4.2 Emergency Discontinuance ... 3.4.2 Emergency Discontinuance If a participating organization detects an attack, intrusion attempt, or other contingency that exploits or jeopardizes the information or systems involved in the information exchange, it might be necessary to abruptly terminate the information exchange without providing written notice to the other party.

(Response) Manufacturers and third party warehouses are both important links in the supply chain and are required to keep records under the provisions of this regulation. It allows FDA to determine whether what was sent at each stage is what was received, and if not, to be able to locate the unaccounted-for food. In a traceback investigation, it is critical that FDA be able to locate and remove from commerce any adulterated food that presents a threat of serious adverse health consequences or death to humans or animals. (Comment 197) Several comments suggest that the information required by the proposed regulation is excessive and that it would require significant changes in business practices to collect and maintain the required information. One comment suggests that requiring records of names, addresses, and telephone numbers of each supplier for each transaction is excessive. A comment suggests that its firm has no way to capture all of the proposed data elements through current sources of transaction documentation. (Response) FDA assumes, and comments agree, that most of the information required by this regulation is already collected and maintained through currently used transaction documents. The final rule requires lot codes or other identifiers only of persons who manufacture, process, or pack food, and only to the extent this information exists. The final rule also does not require that a responsible individual be identified for the immediate previous source and immediate subsequent recipient for each transaction, as was required by the proposed rule. Accordingly, FDA does not modify its assumptions underlying the estimate of the costs of establishing and maintaining records. 6. Estimates of Additional Records Maintenance Costs Too Low In the PRIA, FDA assumed that the burden of maintaining and collecting additional information would be shared among more than one facility. (Comment 198) Comments state that FDA's estimates of recordkeeping burden obtained from the juice HACCP rule are inappropriate. The comments state that using the juice HACCP model substantially underestimates time requirements because most other types of firms would require more resources to achieve the proficiency required under the HACCP rule. (Response) The juice HACCP cost estimates that we used to estimate costs in the PRIA were published before the juice HACCP rule took effect. The cost estimates for that rule were for firms that were not yet in compliance. FDA continues to believe that those cost estimates are an appropriate reference for this final rule, because they represent a precedent for cost

estimates of activities similar to those required in this regulation. (Comment 199) According to numerous discussions with those who are subject to HACCP regulations, the time and money estimates of the costs FDA provided in the seafood HACCP (printed page 71637) rule were about 1/10 the actual values. This represents a big underestimate of the true costs of the regulation.

Level 2 certification assessment. To comply with Level 2 certification assessment requirements, the OSC must meet the requirements set forth in paragraphs (a)(1) and (2) of this section. An OSC undergoes a Level 2 certification assessment as detailed in paragraph (c) of this section to achieve a CMMC Status of either Conditional or Final Level 2 (C3PAO). Achieving a CMMC Status of Level 2 (C3PAO) also (printed page 83229) satisfies the requirements for a CMMC Statuses of Level 1 (Self) and Level 2 (Self) set forth in §§ 170.15 and 170.16 respectively for the same CMMC Assessment Scope. (1) Level 2 certification assessment requirements. The OSC must complete and achieve a MET result for all security requirements specified in § 170.14(c)(3) to achieve the CMMC Status of Level 2 (C3PAO). The OSC must obtain a Level 2 certification assessment from an authorized or accredited C3PAO following the procedures outlined in paragraph (c) of this section. The C3PAO must submit the Level 2 certification assessment results into the CMMC instantiation of eMASS, which then provides automated transmission to SPRS. To maintain compliance with the requirements for a CMMC Status of Level 2 (C3PAO), the Level 2 certification assessment must be completed within three years of the CMMC Status Date associated with the Conditional Level 2 (C3PAO). (i) Inputs into the CMMC instantiation of eMASS. The Level 2 certification assessment results input into the CMMC instantiation of eMASS shall include, at minimum, the following information: (A) Date and level of the assessment. (B) C3PAO name. (C) Assessment unique identifier. (D) For each Assessor conducting the assessment, name and business contact information. (E) All industry CAGE codes associated with the information systems addressed by the CMMC Assessment Scope. (F) The name, date, and version of the SSP. (G) CMMC Status Date. (H) Assessment result for each requirement objective. (I) POA&M usage and compliance, as applicable. (J) List of the artifact names, the return value of the hashing algorithm, and the hashing algorithm used. (ii) Conditional Level 2 (C3PAO). The OSC has achieved the CMMC Status of Conditional Level 2 (C3PAO) if the Level 2 certification assessment results in a POA&M and the POA&M meets all CMMC Level 2 POA&M requirements listed in § 170.21(a)(2). (A) Plan of Action and Milestones. A Level 2 POA&M is allowed only in accordance with the CMMC POA&M requirements listed in § 170.21. (B) POA&M closeout.

CMMC Acquisition rule, prospective DoD contractors and subcontractors should be actively preparing for DoD contract opportunities that will include CMMC Program requirements when performance will require the contractor or subcontractor to process, store, or transmit FCI or CUI. The respective phases of the implementation plan provide adequate time to complete CMMC requirements and DoD program requirements and timelines will dictate the programs that may warrant CMMC Level 3 requirements during the phased implementation of CMMC. DoD considered many alternatives before deciding upon the current CMMC implementation plan. The phased implementation plan is based on CMMC assessment level and type, which DoD believes to be a fair approach for all prospective offerors. Defining the phase-in based on contract type, company size standard, or other potential bases could lead to unfair advantage. Program Managers will have discretion to include CMMC Status requirements or rely upon existing DFARS clause 252.204-7012 requirements, in accordance with DoD policy. The DoD will monitor the Program Managers' exercise of this discretion to ensure a smooth phase-in period. The decision to rely upon CMMC self-assessment in lieu of certification assessment is a Government risk-based decision based upon the nature of the effort to be performed and CUI to be shared. Note that section § 170.20 Standards acceptance states OSCs that completed a DCMA DIBCAC High Assessment with a score of 110 and aligned with CMMC Level 2 Scoping, will receive Final CMMC Status for a Level 2 certification assessment. As noted by one commenter, self-assessments against NIST SP 800-171 are already required, and verifying compliance with applicable security requirements is necessary for the protection of DoD CUI. For all CMMC independent assessments (i.e., Level 2 or 3), DoD policy guides Program Managers in appropriately including these requirements in DoD solicitations. DoD systems that support the procurement process can identify the number of contracts issued that include any specific clause. Such metrics for the CMMC Program are not within the scope of this rule. The seven-year timespan reflects the DoD's estimate for all defense contractors to achieve CMMC compliance. The implementation plan ramps up CMMC assessment requirements over 4 phases, such that the ecosystem will reach maximum capacity by year four. One commenter referenced the response to a specific comment to the 2020 CMMC rule. Those earlier questions about the 2020 rule publication are no longer relevant due to changes made in the more recent 2023 rule publication. DoD estimates acknowledge that contractors with existing contracts may not receive

another contract award or even submit another proposal immediately.

The information safeguarding requirements and cyber incident reporting requirements set forth in DFARS clause 252.204-7012 will not be phased out as a result of this rule. CMMC Program requirements provide DoD with verification, through self or third-party assessment, that defense contractors have, in fact, implemented DoD's cybersecurity protection requirements. In addition, the requirements of this rule will not be fully implemented (and will not appear in all DoD contracts) until 2026 or later. As such, DoD will continue to require the current cybersecurity protections as reflected in the identified DFARS provisions and clauses for contracts that do not include a CMMC requirements. Applicability The CMMC Program will require DoD to identify CMMC Level 1, 2, or 3 as a solicitation requirement for any effort that will cause a contractor or subcontractor to process, store, or transmit FCI or CUI on its unclassified information system(s). Once CMMC is implemented in 48 CFR , DoD will specify the required CMMC Level in the solicitation and the resulting contract.

Summary of Program Changes: DFARS Case 2019-D041 implemented DoD's original model for assessing contractor information security protections, which is referred to as 'CMMC 1.0.' CMMC 1.0 was comprised of five progressively advanced levels of cybersecurity standards and required defense contractors and subcontractors to undergo a certification process to demonstrate compliance with the cybersecurity standards associated with a given CMMC Level. In March 2021, the Department initiated an internal review of CMMC's implementation that engaged DoD's cybersecurity and acquisition leaders to refine policy and program implementation, focusing on the need to reduce costs for small businesses and align cybersecurity requirements to other federal standards and guidelines. This review resulted in CMMC 2.0, which streamlines assessment and certification requirements and improves implementation of the CMMC Program. These changes include: Eliminating Levels 2 and 4, and renaming the remaining three CMMC Levels as follows: Level 1 will remain the same as CMMC 1.0 Level 1; Level 2 will be similar to CMMC 1.0 Level 3; Level 3 will be similar to CMMC 1.0 Level 5. Removing CMMC-unique requirements and maturity processes from all levels; For CMMC Level 1, allowing annual self-assessments with an annual affirmation by company leadership; Allowing a subset of companies at Level 2 to demonstrate compliance through self-assessment rather than C3PAO assessment. For CMMC Level 3, requiring Department-conducted assessments; and Developing a time-bound and enforceable POA&M process. The CMMC Program will be implemented through publication of rules for both title 32 CFR and title 48 CFR. Both rules will have public comment periods.

Background A. Statement of Need for This Rule

Further, the court added that the requirement does not 'say anything about how effective a mechanism must be, how universally it must be enforced, or how impervious to human error or hacker malfeasance it must be.' [355] Therefore, the Department believes it is necessary to add definitions that distinguish between implementation of the administrative and technical safeguards by separately describing how regulated entities can comply with requirements to implement technical safeguards and install technical solutions.

b. Proposal The Department proposes to define the term 'deploy' to identify a specific type of 'implementation.' We believe that the new term and definition would help to better describe the compliance obligations for implementation specifications related to the use of technology for securing the confidentiality, integrity, or availability of ePHI. As proposed, the definition would require a regulated entity to ensure that technology is in place, configured for use, and actually in use and operational throughout the regulated entity. The Department's proposed use of the term helps illustrate its purpose and utility in clarifying that policies and procedures, while necessary, are insufficient to meet requirements for technical safeguards. For example, the Department is proposing to create a new requirement for regulated entities to verify that business associates have deployed technical safeguards—that is, the technology is configured and operational, not only addressed in policies and procedures. [356] In another example, the Department is proposing new implementation specifications under the access control standard that would require a regulated entity to deploy technical controls for relevant electronic information systems so that the system is configured and applied to limit access to only users and technology assets that have been granted access rights. [357] In the automatic logoff implementation specification for that same standard, the Department is proposing to replace the requirement to implement electronic procedures for terminating an electronic session with a requirement to deploy technical controls that terminate an electronic session after a period of inactivity. [358] In each case, the technical controls must not only be configured for use, but they also must be applied to and in effect in all ePHI and relevant electronic information systems. The Department proposes to define the term 'implement' to clarify that a safeguard must be put into place and be in effect throughout the enterprise, as opposed to only some components of a regulated entity's relevant information

systems (e.g., some laptops or servers) or applied to a subset of ePHI. The Department also proposes the term to further clarify what it means to configure and put technology, technical controls, and related policies and procedures into effect and be in use, operational, and function as expected throughout the regulated entity's enterprise (i.e.,

(Comment 47) One comment states it is not clear in the proposed regulations whether retail bakeries and delicatessens are subject to these regulations. Although the registration requirements exempt them entirely, the recordkeeping rule only contains an exemption from establishing and maintaining records with the names of immediate subsequent recipients of foods sold directly to consumers. This implies that they still need to keep track of ingredient lots used in each production. In such operations, production usually consists of a wide variety of products made daily and in very small quantities. Keeping track of ingredients used in each and every product made daily is virtually impossible, and if required, would financially break every retail bakery or delicatessen, most of which are already struggling to compete in the dwindling market being taken over by supermarket chains. The comment requests that FDA look seriously at totally exempting any retail food operation with 10 or less employees from any of the requirements of the proposed regulations, particularly recordkeeping. If this is not possible, the comment proposes that FDA consider an alternative choice if they do not keep records of ingredients used in products, that if any contaminated ingredient is found, or brought to their attention, that they agree to destroy all manufactured products currently in stock (made from this ingredient or not). This alternative would have the same safety effect, but would be a lot less costly than keeping records. (Response) A bakery or delicatessen is excluded from all of the requirements in subpart J of this final rule if its sales of food it prepares and sells to consumers for immediate consumption are more than 90 percent of its total food sales. (printed page 71580) Food is for immediate consumption when the food is capable of being eaten immediately with no further preparation. However, if the bakery or delicatessen does not qualify for the restaurant/retail facility exclusion in § 1.327(b) of this final rule, there is also an exclusion for retail food establishments that may apply. Under § 1.327(f) of this final rule, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements in this subpart, except the record access requirements for existing records. The exclusion is based on the number of full-time equivalent employees at each retail food establishment and not the entire business, which may own numerous retail stores.

means information that identifies the DIB participant, whether directly or indirectly, by the grouping of information that can be traced back to the DIB participant (e.g., program description, facility locations). (b) Compromise means disclosure of information to unauthorized persons or a violation of the security policy of a system in which unauthorized intentional, or unintentional, disclosure, modification, destruction, loss of an object, or the copying of information to unauthorized media may have occurred. (c) Covered defense information means unclassified information that: (1) Is: (i) Provided by or on behalf of the DoD to the DIB participant in connection with an official DoD activity; or (ii) Collected, developed, received, transmitted, used, or stored by the DIB participant in support of an official DoD activity; and (2) Is: (i) Technical information marked for restricted distribution in accordance with DoD Directive 5230.25, Withholding of Unclassified Technical Data From Public Disclosure, or DoD Directive 5230.24, Distribution Statements on Technical Documents; (ii) Information subject to export control under the International Traffic in Arms Regulations (ITAR) (http://pmddtc.state.gov/regulations_laws/itar_official.html), or the Export Administration Regulations (EAR) (<http://ecfr.gpoaccess.gov> , Title 15, part 730); (iii) Information designated as Critical Program Information (CPI) in accordance with DoD Instruction 5200.39, Critical Program Information (CPI) Protection within the Department of Defense; (iv) Information that hostile intelligence systems might obtain that could be interpreted or pieced together to derive critical intelligence in time to be useful to adversaries as described in 5205.02-M, DoD Operations Security (OPSEC Program Manual; (v) Personally Identifiable Information (PII) that can be used to distinguish or trace an individual's identity in accordance with DoD Directive 5400.11, DoD Privacy Program; (vi) Information bearing current and prior designations indicating unclassified controlled information (e.g., For Official Use Only, Sensitive But Unclassified, and Limited Official Use, DoD Unclassified Controlled Nuclear Information, Sensitive Information) that has not been cleared for public release in accordance with DoD Directive 5230.29, Clearance of DoD Information for Public Release (see also Appendix 3 of DoD 5200.1-R, Information Security Program Regulation); or (vii) Any other information that is exempt from mandatory public disclosure under DoD Directive 5400.07, DoD Freedom of Information Act (FOIA) Program, and DoD Regulation 5400.7-R,

·DoD Freedom of Information Program·. (d) Covered DIB systems means an information system that is owned or operated by or for a DIB participant and that processes, stores, or transmits covered defense information. (e) Cyber incident

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense General Services Administration National Aeronautics and Space Administration [Docket No. 2024-0054; Sequence No. 1] AGENCY: Department of Defense (DoD), General Services Administration (GSA), and National Aeronautics and Space Administration (NASA). ACTION: Notice of request for information (RFI). SUMMARY: DoD, GSA, and NASA recently established Federal Acquisition Regulation (FAR) part 40, Information Security and Supply Chain Security. The intent of this RFI is to solicit feedback from the general public on the scope and organization of FAR part 40. DATES: Interested parties should submit written comments to the Regulatory Secretariat Division at the address shown below on or before June 10, 2024 to be considered in the formation of the changes to FAR part 40. ADDRESSES: Submit comments in response to this RFI to the Federal eRulemaking portal at <https://www.regulations.gov> by searching for ·RFI FAR part 40·. Select the link ·Comment Now· that corresponds with ·RFI FAR part 40·. Follow the instructions provided on the ·Comment Now· screen. Please include your name, company name (if any), and ·RFI FAR part 40· on your attached document. If your comment cannot be submitted using <https://www.regulations.gov> , call or email the points of contact in the FOR FURTHER INFORMATION CONTACT section of this document for alternate instructions. Instructions: Response to this RFI is voluntary. Respondents may answer as many or as few questions as they wish. Each individual or entity is requested to submit only one response to this RFI. Please identify your answers by responding to a specific question or topic if possible. Please submit responses only and cite ·RFI FAR part 40· in all correspondence related to this RFI. Comments received generally will be posted without change to <https://www.regulations.gov> , including any personal and/or business confidential information provided. Public comments may be submitted as an individual, as an organization, or anonymously (see frequently asked questions at <https://www.regulations.gov/faq>). To confirm receipt of your comment(s), please check <https://www.regulations.gov> , approximately two-to-three days after submission to verify posting. FOR FURTHER INFORMATION CONTACT: For clarification of content, contact Ms. Malissa Jones, Procurement Analyst, at 571-882-4687 or by email at malissa.jones@gsa.gov . For information pertaining to status, publication schedules, or alternate instructions for submitting comments if <https://www.regulations.gov>

Third phrase of PE.L1-b.1.ix (FAR b.1.ix.*) 3.10.5 SC.L1-b.1.x 3.13.1 SC.L1-b.1.xi 3.13.5 SI.L1-b.1.xii 3.14.1 (printed page 89130) SI.L1-b.1.xiii 3.14.2 SI.L1-b.1.xiv 3.14.4 SI.L1-b.1.xv 3.14.5 *.Three of the FAR 52.204-21 requirements were broken apart by ·phrase· when NIST SP 800-171 Rev 2 was developed. (iii) Additional explanatory material can be found in the CMMC Level 1 Assessment Guide located at <https://DoDcio.defense.gov/·CMMC/·> . (2) [Reserved]. §.170.16 CMMC Level 2 Self-Assessment and Affirmation requirements. (a) Level 2 Self-Assessment. To comply with CMMC Level 2 Self-Assessment requirements, the OSA must meet the requirements detailed in paragraphs (a)(1) and (2) of this section. Meeting the CMMC Level 2 Self-Assessment requirements detailed in paragraphs (a)(1) and (2) of this section also satisfies the CMMC Level 1 Self-Assessment requirements detailed in §.170.15 for the same CMMC Assessment Scope. (1) Self-Assessment. The OSA must complete and achieve a MET result for all security requirements specified in §.170.14(c)(3). The OSA must conduct a self-assessment in accordance with the procedures set forth in paragraph (c)(1) of this section and submit assessment results in SPRS. To maintain compliance with CMMC Level 2 Self-Assessment requirements, the OSA must perform a CMMC Level 2 Self-Assessment on a triennial basis and submit the results in SPRS. (i) SPRS inputs. The self-assessment results in the Supplier Performance Risk System (SPRS) shall include, at minimum, the following information: (A) CMMC Level. (B) Assessment Date. (C) Assessment Scope. (D) All industry CAGE code(s) associated with the information system(s) addressed by the CMMC Assessment Scope. (E) Overall self-assessment score (e.g., 105 out of 110). (F) POA&M usage and compliance status, as applicable. (ii) Conditional self-assessment. OSAs have achieved CMMC Level 2 Conditional Self-Assessment if the Level 2 self-assessment results in a POA&M and the POA&M meets all the CMMC Level 2 POA&M requirements listed in §.170.21(a)(2). (A) Plan of Action and

Milestones. A Level 2 POA&M is allowed only in accordance with the CMMC POA&M requirements listed in § 170.21. (B) POA&M closeout. The OSA must implement all CMMC Level 2 security requirements and close out the POA&M within 180 days of the initial self-assessment. Upon remediation of the remaining requirements, the OSA must perform a POA&M closeout self-assessment and post compliance results to SPRS. If the POA&M is not closed out within the 180-day timeframe, the Conditional Level 2 Self-Assessment status of the OSA will expire. If Conditional Level 2 Self-Assessment expires within the period of performance of a contract, standard contractual remedies will apply, and the OSA will be ineligible for additional awards with CMMC Level 2 Self-Assessment or higher requirements for the information system within the CMMC Assessment Scope. (iii) Final Self-Assessment.

Numerous comments requested that the DoD provide a definition for Security Protection Data (SPD) and configuration data, as well as requirements for SPD to help understand the scope of SPD and how that impacts the scope of Security Protection Assets and the assessment requirements of ESPs. One comment recommended the removal of the definition and use of SPD. Multiple comments requested more information on the definition and scoping of Security Protection Assets, their relationship to CUI, and their requirements. Some comments suggested that the definition narrow the scope of Security Protection Assets and/or their security and assessment requirements. Other comments recommended eliminating the concept of SPA. Additional comments recommended changing the assessment requirements for SPAs to be the same as CRMAs Specialized Assets applicable NIST SP 800-171 R2 requirements, commensurate with the level of involvement with the security of CUI or to only assess the requirements provided by the SPA. Two comments recommended that the phrase ·irrespective of whether these assets process, store, or transmit CUI· be removed from the definition of SPA. Two comments asked for clarification on the requirements for CSPs that only handle SPD. Two comments recommended different security and assessment requirements for ESPs that host SPD but do not process, store, or transmit CUI. Response: DoD added a CMMC definition for Security Protection Data to the rule. The DoD considered the NIST definitions for System Information and Security Relevant Information in the development of the CMMC definition for SPD. This rule does not regulate OSA Security Protection Data, but instead implements existing regulatory requirements for the safeguarding of CUI, as defined in 32 CFR 2002.14(h)(2) and implemented by DFARS clause 252.204-7012. This clause requires protection of security protection assets and security protection data through its specification of NIST SP 800-171. DoD does not agree with the commentor's statement that the definition of Security Protection Assets ·is an exceedingly dangerous adjustment to the NIST SP 800-171 Revision 2 Paragraph 1.1 Scope of Applicability·. Security Protection Assets provide security to the entirety of an OSA's assessment scope which includes CUI Assets and other in-scope assets. The SPD definition also defines configuration data as data required to operate a security protection asset. This limits the possible interpretations of configuration data. Further, the rule has been updated to reflect that ESPs that do NOT process, store, or transmit CUI do not require CMMC assessment or certification.

(Response) FDA agrees with the comment that a model is needed to determine the savings in investigation traceback times, and the numbers of illnesses that would be avoided from this regulation. FDA has developed a model of the benefits, which is described later in this section. However, FDA does not agree that the benefits should be compared to the current system for recalling products since few investigations result in recalls. Instead, FDA believes that benefits from this final rule will primarily be from faster investigations leading up to preventive actions, including recalls. A recall or other preventive action is made only after a product has been implicated. The benefits from the recordkeeping rule are to improve the accuracy and speed with which a product is implicated. If recalls or other preventive actions are made too quickly and cover too wide a range of products, there is the very real danger of a recurrence of the outbreak if the source is not investigated. For that reason, the benefits from the regulation include not only faster traceback investigation times, but also higher rates of completed traceback investigations, and the commensurate reduction in outbreak recurrences. (Comment 181) One comment states that the analysis failed to meet Office of Management and Budget (OMB) guidelines for regulatory impact analysis by failing to do the following: (1) Adequately consider the need and consequences of the regulation and (2) show that the benefits outweigh the costs of the regulation. In addition, the comment states that the purpose of the regulation is to expand the agency's jurisdiction, rather than to maximize the net benefits to society, and that alternatives with the highest net benefits (including the alternative not to regulate) were not chosen. Finally, the comment states that the analysis failed to consider the condition of the affected food industries, potential future regulatory actions, and

the weak state of the national economy as required. (Response) In the PRIA, we stated that the need for these regulations is to enable FDA to respond to, and help contain, food for which the agency has a reasonable belief that it is adulterated and presents a threat of serious adverse health consequences or death to humans or animals. In the final rule we bolster the explanation of the need for the regulation by analyzing vulnerabilities due to shortfalls in current recordkeeping practices. These shortfalls are shown to inhibit current outbreak investigation efforts and, by extension, efforts to mitigate serious adverse health consequences or death to humans or animals. The perceived vulnerability of the U.S. food supply to an attack, as articulated by Congressional passage of the (printed page 71614) Bioterrorism Act, elevates the importance of addressing these shortfalls.

Scope. This section implements 10 U.S.C. 2327(b) . 225.771-1 Definition. ·State sponsor of terrorism,· as used in this section, is defined in the provision at 252.225-7050, Disclosure of Ownership or Control by the Government of a Country that is a State Sponsor of Terrorism. 225.771-2 Prohibition. (a) The contracting officer shall not award a contract of \$150,000 or more to a firm when a foreign government that is a state sponsor of terrorism owns or controls, either directly or indirectly, a significant interest in· (i) The firm; (ii) A subsidiary of the firm; or (iii) Any other firm that owns or controls the firm. (b) For restrictions on subcontracting with a firm, or a subsidiary of a firm, that is identified by the Secretary of Defense as being owned or controlled by the government of a country that is a state sponsor of terrorism, see 209.405-2. 225.771-3 Notification. Any disclosure that the government of a country that is a state sponsor of terrorism has a significant interest in an offeror, a subsidiary of an offeror, or any other firm that owns or controls an offeror shall be forwarded through agency channels to the address at PGI 225.771-3. 225.771-4 Waiver of prohibition. The prohibition in 225.771-2 may be waived if the Secretary of Defense determines that a waiver is not inconsistent with the national security objectives of the United States in accordance with 10 U.S.C. 2327(c) . 225.771-5 Solicitation provision. Use the provision at 252.225-7050, Disclosure of Ownership or Control by the Government of a Country that is a State Sponsor of Terrorism, in solicitations, including solicitations using FAR part 12 procedures for the acquisition of commercial items (other than commercial satellite services), that are expected to result in contracts of \$150,000 or more. If the solicitation includes the provision at FAR 52.204-7, do not separately list the provision 252.225-7050 in the solicitation. (printed page 73490) PART 252·SOLICITATION PROVISIONS AND CONTRACT CLAUSES 11. Amend section 252.204-7007 by· a. Removing the clause date ·(AUG 2014)· and adding ·(DEC 2014)· in its place; b. Removing paragraph (d)(1)(i); c. Redesignating paragraphs (d)(1)(ii) through (v) as (d)(1)(i) through (iv); and d. Adding a new paragraph (d)(1)(v). The addition reads as follows: 252.204-7007 Alternate A, Annual Representations and Certifications. * * * * * (d)(1) * * * (v) 252.225-7050, Disclosure of Ownership or Control by the Government of a Country that is a State Sponsor of Terrorism. Applies to all solicitations expected to result in contracts of \$150,000 or more. * * * * * 252.209-7001 [Removed and Reserved] 12. Remove and reserve section 252.209-7001. 252.209-7002 [Amended] 13. Amend section 252.209-7002 introductory text by removing ·209.104-70(b)· and adding ·209.104-70· in its place. 14. Revise section 252.209-7004 to read as follows: 252.209-7004 Subcontracting with Firms that are Owned or Controlled by the Government of a Country that is a State Sponsor of Terrorism.

fectively monitor and address IoT product security risks. Jasyn briefly summarized the threat landscape and some recent high-profile events as motivating factors for OEMs to consider product security. He then described in detail Zebra's approach, based on three principles: There were some discussions on distinctions between IT and IoT, and how some assumptions about how security is implemented in IT products do not hold for IoT products, particularly when addressing safety, privacy, different types of supply chains, and the often unique and highly-diverse and complex environments within which the IoT devices are used. Panelists generally agreed that consideration of complete IoT products, instead of the specific IoT devices, will require changes in the ways in which associated risk assessments are performed, necessarily widening the scope. It will also change the ongoing risk management activities, requiring more types of activities to address the full IoT product instead of just considering the IoT device. This, in turn, will require the ability to obtain more information from throughout the supply chain. For

The Department intends and has always intended the physical safeguards to apply to any location where a regulated entity might possess ePHI, including the physical premises and interior and exterior of a building, and any location that might affect the confidentiality, integrity, or

availability of ePHI. Additionally, given the mobility of technology today, including workstations that may access ePHI, we believe it would be more appropriate to use the term facility to make clear that the physical safeguards are to apply throughout the premises of the regulated entity. For the same reasons discussed above, we also propose to clarify that the physical safeguards serve to protect relevant electronic information systems, as we propose to define the term elsewhere in this NPRM, rather than all electronic information systems. Further, the Department proposes to better standardize the administrative, physical, and technical safeguard requirements by using defined terms where they exist. 13. Adding a Definition of ‘Relevant Electronic Information System’

a. Issues To Address The Security Rule requires a regulated entity to ensure the confidentiality, integrity, and availability of all of the ePHI it creates, receives, maintains, or transmits. [377] To protect the ePHI as required, a regulated entity must also protect the electronic information systems that create, receive, maintain, or transmit ePHI and the electronic information systems that otherwise affect the confidentiality, integrity, or availability of ePHI. The Department believes that regulated entities are not consistently protecting ePHI in a manner that is consistent with their Security Rule obligations and believes that it is necessary to clarify the scope of those obligations. We believe that creating a new defined term for the electronic information systems to which the Security Rule requirements apply will help achieve this goal by ensuring that regulated entities fully understand how their technology assets and the architecture of their electronic information systems affect the confidentiality, integrity, and availability of ePHI.

b. Proposal The Department proposes to add and define the term ‘relevant electronic information system’ to mean an electronic information system that creates, receives, maintains, or transmits ePHI or that otherwise affects the confidentiality, integrity, or availability of ePHI. We believe that distinguishing between a relevant electronic information system and an electronic information system, as proposed, would further clarify the scope of regulated entities’ compliance obligations, including the obligation of regulated entities to understand the relationship between their various electronic information systems and the confidentiality, integrity, and availability of ePHI.

(7) In addition to mailing or delivering notice of the proposed sale to prospective bidders, the Contractor may (when the results are expected to justify the additional expense) display a notice of the proposed sale in appropriate public places, e.g., publish a sales notice on the Internet in appropriate trade journals or magazines and local newspapers. (8) The plant clearance officer or representative will witness the bid opening. The Contractor shall submit, either electronically or manually, two copies of the bid abstract. (9) The following terms and conditions shall be included in sales contracts involving the demilitarization, mutilation, or destruction of property: (i) Demilitarization, mutilation, or destruction on Contractor or subcontractor premises. Item(s) ___ require demilitarization, mutilation, or destruction by the Purchaser. Insert item number(s) and specific demilitarization, mutilation, or destruction requirements for item(s) shown in Defense Demilitarization Manual, DoDM 4160.28-M, edition in effect as of the date of this contract. Demilitarization shall be witnessed and verified by a Government representative using DRMS Form 145 or equivalent. (ii) Demilitarization, mutilation, or destruction off Contractor or subcontractor premises. (A) Item(s) ___ require demilitarization, mutilation, or destruction by the Purchaser. Insert item number(s) and specific demilitarization, mutilation, or destruction requirements for item(s) shown in Defense Demilitarization Manual, DoDM 4160.28-M, edition in effect as of the date of this contract. Demilitarization shall be witnessed and verified by a Government representative using DRMS Form 145 or equivalent. (B) Property requiring demilitarization shall not be removed, and title shall not pass to the Purchaser, until demilitarization has been accomplished and verified by a Government representative. Demilitarization (printed page 52145) will be accomplished as specified in the sales contract. Demilitarization shall be witnessed and verified by a Government representative using DRMS Form 145 or equivalent. (C) The Purchaser agrees to assume all costs incident to the demilitarization and to restore the working area to its present condition after removing the demilitarized property. (iii) Failure to demilitarize. If the Purchaser fails to demilitarize, mutilate, or destroy the property as specified in the contract, the Contractor may, upon giving 10 days written notice from date of mailing to the Purchaser: (A) Repossess, demilitarize, and return the property to the Purchaser, in which case the Purchaser hereby agrees to pay to the Contractor, prior to the return of the property, all costs incurred by the Contractor in repossessing, demilitarizing, and returning the property;

Headquarters Services White House Military Office AP2.2.2. Department of the Army. Address requests for Headquarters, U.S. Army, records, or if there is uncertainty as to which Army activity may have the records, address requests to: Department of the Army, Freedom of Information and Privacy Acts Office, TAPC-PDR-PF, 7798 Cissna Road, Suite 205, Springfield, VA 22150-3166. <https://www.rmda.belvoir.army.mil/rmdaxml/rmda/FPHomePage.asp> . AP2.2.3. Department of the Navy. Address requests to the Commanding Officer of any Navy or Marine Corps activity. Clearly indicate that the request is a FOIA request. For Secretary of the Navy, Chief of Naval Operations, and Naval Historical Center records, or if there is uncertainty as to which Navy activity may have the records, send requests to: Chief of Naval Operations, DNS-36, 2000 Navy Pentagon, Washington, DC 20350-2000. Electronic requests may be filed at <http://foia.navy.mil/> . For U.S. Marine Corps records, or if there is uncertainty as to which Marine activity may have the records, send requests to: Commandant of the Marine Corps, HQ USMC (ARSF), 2 Navy Annex, Washington, DC 20380-0001. <http://hqinet001.hqmc.usmc.mil/FOIA/index.htm> . AP2.2.4. Department of the Air Force. Address requests to the Commander of any Air Force installation, major command, or field operating agency, to the attention of the FOIA Requester Service Center. For Headquarters, United States Air Force, records, or if there is uncertainty as to which Air Force activity may have the records, send requests to: Department of the Air Force, HAF/ICIOD (FOIA), 1000 Air Force Pentagon, Washington, DC 20330-1000. <http://www.foia.af.mil/> . AP2.2.5. Defense Commissary Agency. Defense Commissary Agency, FOIA/Privacy Act Officer, 1300 E. Avenue, Fort Lee, VA 23801-1800. <http://www.commissaries.com/foiainfo.cfm> . AP2.2.6. Defense Contract Audit Agency (DCAA). Address requests to any DCAA regional office or to DCAA Headquarters. For Headquarters, DCAA, records, or if there is uncertainty as to which DCAA region may have the records, send requests to: Defense Contract Audit Agency, ATTN: CMR, FOIA Requester Service Center, 8725 John J. Kingman Road, Suite 2135, Fort Belvoir, VA 22060-6219. DCAA regional office addresses can be found at: <http://www.dcaa.mil/foia.htm> . AP2.2.7. Defense Contract Management Agency. Defense Contract Management Agency, Attn: DCMA-DSA, 6350 Walker Lane #300, Alexandria, VA 22310-3226. <http://www.dcma.mil/foia.htm> . AP2.2.8. Defense Finance and Accounting Service

Avi Gopstein Smart Grid and Cyber Physical Systems Office Engineering Laboratory The North American Electric Reliability Corporation (NERC) Critical Infrastructure Protection (CIP) Reliability Standards [NERC CIP] are a set of requirements designed to mitigate the risk of a compromise that could lead to misoperation or instability in the Bulk Electric System (BES). The scope of the CIP Cyber Security Standards is restricted to BES Cyber Systems that would impact the reliable operation of the BES. The Reliability Standards cover topics like the identification and protection of BES Cyber Assets, defining logical isolation perimeters, personnel and training, BES Cyber System security management, disaster recovery planning, physical security, and supply chain risk management.

Potential Assessment Considerations · Are system components (e.g., workstations, servers, email gateways, mobile devices) for which malicious code protection must be provided identified and documented [a]? SI.L2-3.14.2 · Malicious Code Protection [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13 251 KEY REFERENCES · NIST SP 800-171 Rev. 2 3.14.2 · FAR Clause 52.204-21 b.1.xiii

(Response) Growers of raw agricultural commodities that meet the definition of “farm” in § 1.328 are excluded from the requirements of subpart J of this final rule. A cooperative that accumulates raw agricultural commodities from growers, and does not meet the exemption for retail food establishments that employ 10 or fewer full-time equivalent employees in § 1.327(f) of the final rule, is subject to the requirements in § 1.337 of the final rule regarding the immediate previous sources of food. Distribution of food from the cooperative directly to consumers is excluded from the requirements of § 1.345 of the final rule regarding the immediate subsequent recipients of food.

2. Intrastate (Comment 24) One comment agrees that the requirement for U.S. domestic firms, whether shipping interstate or intrastate, to establish and maintain records as provided in the proposed regulation will maximize FDA’s capability to implement traceback procedures within the borders of the United States. Another comment states that a finding that a certain food is intentionally contaminated—even if only distributed or sold locally—could have widespread, nationwide, even international, economic implications. The comment states that the recent “mad cow” episode in Canada demonstrates that restrictions might be imposed on the distribution and sale of implicated products, or consumers across the country may decide not to buy the products thus impacting the economy as a whole. As a result, the comment states that FDA is correct in concluding that all persons who

manufacture, process, pack, transport, distribute, receive, hold, or import food should be subject to the recordkeeping requirements whether or not they directly engage in interstate activities involving food.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analysis to advance the development and productive use of information technology. ITL's responsibilities include the development of technical, physical, administrative, and management standards and guidelines for the cost-effective security and privacy of sensitive unclassified information in Federal computer systems. This Interagency Report discusses ITL's research, guidance, and outreach efforts in computer security and its collaborative activities with industry, government, and academic organizations. 3 There are other types of vulnerabilities, such as physical vulnerabilities, that are not included in these categories.

) would require a regulated entity to establish and implement written procedures for terminating a workforce member's access to ePHI and relevant electronic information systems, (printed page 950) and to locations where ePHI or relevant electronic information systems might be accessed. Proposed paragraph (a)(9)(ii)(C)(2) would require that the workforce member's access be terminated as soon as possible, but no later than one hour after the workforce member's employment or other arrangement ends. A proposed implementation specification for notification at proposed 45 CFR 164.308(a)(9)(ii)(D) would require a regulated entity to establish and implement written procedures for notifying another regulated entity of a change in, or termination of, a workforce member's authorization to access ePHI or relevant electronic information systems. Proposed paragraph (a)(9)(ii)(D)(1) would require the regulated entity to establish and implement written procedures for notifying another regulated entity after a change in or termination of a workforce member's authorization to access ePHI or relevant electronic information systems that are maintained by such other regulated entity where the workforce member is or was authorized to access such ePHI or relevant electronic information systems by the regulated entity making the notification. Proposed paragraph (a)(9)(ii)(D)(2) would require the notice to be provided as soon as possible, but no later than 24 hours after the workforce member's authorization to access ePHI or relevant electronic information systems is changed or terminated. Finally, a proposed new implementation specification for maintenance at proposed 45 CFR 164.308(a)(9)(ii)(E) would require a regulated entity to review and test its written workforce security policies and procedures at least once every 12 months and to modify them as reasonable and appropriate. [564] The proposed implementation specifications for termination procedures and notification implementation align with the Department's essential CPG for Revoke Credentials for Departing Workforce Members, Including Employees, Contractors, Affiliates, and Volunteers by requiring a regulated entity to promptly remove access following a change in or termination of a user's authorization to access ePHI. [565] I. Section 164.308(a)(10)(i)-Standard: Information Access Management The purpose of the standard for information access management is to protect ePHI by reducing the risk that other persons or technology assets may access the information for their own reasons. Existing HHS guidance explains that restricting access to only those persons and entities with a need for access is a basic tenet of security. [566]

3.2.2 Step 2: Execute the Implementation Plan ... 3.2.2 Step 2: Execute the Implementation Plan
After the implementation plan is developed, reviewed, and approved by senior members of the planning team, the plan may then be executed. 3.2.2.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the

development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The purpose of this publication is to evaluate NFT technology and identify potential security concerns. This will promote the secure development of NFT implementations and raise awareness as to possible security concerns. The focus is on the smart contract representation and sales of NFTs and associated blockchain aspects.

The HIPAA Security Rule update follows this timeline: - December 27, 2024: HHS OCR published the Notice of Proposed Rulemaking (NPRM) - March 2025: Public comment period closed (approximately 5,000 comments received) - Current status: OCR is reviewing comments and drafting the final rule - Expected finalization: May 2026 (per the HHS regulatory agenda) Once finalized, covered entities and business associates will have an implementation period (typically 180 days to 1 year) to comply with the new requirements. The OCR estimated first-year compliance costs of approximately \$9 billion across all covered entities and business associates.

(C) From subsections (d) and (f) because requiring OSD to grant access to records and agency rules for access and amendment of records would unfairly impede the investigation of allegations of unlawful activities. To require OSD to confirm or deny the existence of a record pertaining to a requesting individual may in itself provide an answer to that individual relating to an ongoing investigation. The investigation of possible unlawful activities would be jeopardized by agency rules requiring verification of record, disclosure of the record to the subject, and record amendment procedures. (21) System identifier and name. DWHS E05, Mandatory Declassification Review Files. (i) Exemption. Information classified under E.O. 13526, as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (ii) Authority. 5 U.S.C. 552a(k)(1). (iii) Reasons. From subsection 5 U.S.C. 552a(d) because granting access to information that is properly classified pursuant to E.O. 13526, as implemented by DoD 5200.1-R, may cause damage to the national security. (22) System identifier and name. DPFPA 05, Computer Aided Dispatch and Records Management System (CAD/RMS). (i) Exemption. Portions of this system that fall within 5 U.S.C. 552a(j)(2) and/or (k)(2) are exempt from the following provisions of 5 U.S.C. 552a, section (c)(3) and (4); (d); (e)(1) through (e)(3); (e)(4)(G) through (I); (e)(5); (e)(8); (f) and (g) of the Act, as applicable. (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(2). (iii) Reasons. (A) From subsections (c)(3) and (4) because making available to a record subject the accounting of disclosure from records concerning him or her would specifically reveal any investigative interest in the individual. Revealing this information could reasonably be expected to compromise ongoing efforts to investigate a known or suspected offender by notifying the record subject that he or she is under investigation. This information could also permit the record subject to take measures to impede the investigation, e.g. destroy evidence, intimidate potential witnesses, or flee the area to avoid or impede the investigation.

While outside the requirements of the NISPOM, when a classified contract also includes provisions for protection of CUI, contractors will comply with those contract requirements. § 117.16 Visits and meetings. (a) Visits. This paragraph applies when, for a lawful and authorized USG purpose, it is anticipated that classified information will be disclosed during a visit to a cleared contractor facility or to a USG facility. (1) Classified visits. The number of classified visits will be held to a minimum. The contractor: (i) Must determine that the visit is necessary and the purpose of the visit cannot be achieved without access to, or disclosure of, classified information. (ii) Will establish procedures to ensure positive identification of visitors, appropriate PCL, and need-to-know prior to the disclosure of any classified information. (iii) Will establish procedures to ensure that visitors are only afforded access to classified information consistent with the purpose of the visit. (2) Need-to-know determination. The responsibility for determining need-to-know in connection with a classified visit rests with the individual who will disclose classified information during the visit. Need-to-know is generally based on a contractual relationship between the contractors. In other circumstances, disclosure of the information will be based on an assessment that the receiving contractor has a bona fide need to access the information in furtherance of a GCA purpose. (3) Visits by USG representatives. Representatives of the USG, when acting in their official capacities as inspectors, investigators, or auditors, may visit a contractor's facility, provided these representatives present appropriate USG credentials upon arrival. (4) Visit authorization. (i) If a visit requires access to classified information, the host contractor will verify the visitor's PCL level. Verification of a visitor's PCL may be

accomplished by a review of a CSA-designated database that contains the information or by a visit authorization letter (VAL) provided by the visitor's employer. (ii) If a CSA-designated database is not available and a VAL is required, contractors will include in all VALs: (A) Contractor's name, employee's name, address, and telephone number, assigned commercial and government entity (CAGE) code, if applicable, and certification of the level of the entity eligibility determination. (B) Name, date and place of birth, and citizenship of the employee intending to visit. (C) Certification of the proposed visitor's PCL and any special access authorizations required for the visit. (D) Name of person(s) to be visited. (E) Purpose and sufficient justification for the visit to allow for a determination of the necessity of the visit. (F) Date or period during which the VAL is to be valid. (5) Long term visitors. (i) When USG employees or employees of one contractor are temporarily stationed at another contractor's facility, the security procedures of the host contractor will govern.

3.1.1 Facilities, Fleet, and Equipment Management Information Type... 3.1.1 Facilities, Fleet, and Equipment Management Information Type Facilities, Fleet, and Equipment management involves the maintenance, administration, certification, and operation of office buildings, fleets, machinery, and other capital assets considered as possessions of the Federal government.

Control OC-01: anization uses real-time or near real-time information to understand and consistently act upon the cybersecurity risks associated with its suppliers and the products and services it acquires and uses. Cybersecurity information is constantly shared throughout the organization and with authorized third parties. | ## Appendix C. Glossary ## CSF Category A group of related cybersecurity outcomes that collectively comprise a CSF Function. ## CSF Community Profile A baseline of CSF outcomes that is created and published to address shared interests and goals among a number of organizations. A Community Profile is typically developed for a particular sector, subsector, technology, threat type, or other use case. An organization can use a Community Profile as the basis for its own Target Profile. ## CSF Core A taxonomy of high-level cybersecurity outcomes that can help any organization manage its cybersecurity risks. Its components are a hierarchy of Functions, Categories, and Subcategories that detail each outcome. ## CSF Current Profile A part of an Organizational Profile that specifies the Core outcomes that an organization is currently achieving (or attempting to achieve) and characterizes how or to what extent each outcome is being achieved. ## CSF Function The highest level of organization for cybersecurity outcomes. There are six CSF Functions: Govern, Identify, Protect, Detect, Respond, and Recover. ## CSF Implementation Example A concise, action-oriented, notional illustration of a way to help achieve a CSF Core outcome. ## CSF Informative Reference A mapping that indicates a relationship between a CSF Core outcome and an existing standard, guideline, regulation, or other content. ## CSF Organizational Profile A mechanism for describing an organization's current and/or target cybersecurity posture in terms of the CSF Core's outcomes. ## CSF Quick Start Guide A supplementary resource that gives brief, actionable guidance on specific CSF-related topics.

3.2.1 3.2.1
.....
.....
.....
..... ## 3.

and creating additional case studies that showcase mature C-SCRM programs that can be used by aspiring organizations as guidance. <!-- image --> The authors conducted in-depth interviews with six organizations that represented a variety of industry sectors and sizes. The purpose of this research was to better understand organizational viewpoints on Cyber Supply Chain Risk Management as well as the challenges faced by organizations. The goal was not to gain an understanding of the general consensus around the topic but rather to dive deeply into the experiences of a few organizations. The authors chose semistructured interviews as the most appropriate method for collecting data about C-SCRM key practices for three reasons: 1. The status of C-SCRM key practices is often considered sensitive and is not broadly shared. 2. The subject matter is complex and non-standardized, meaning that organizations may use different terms for the same concepts. 3. Semi-structured interviews are superior to more quantitative data collection methods for studies that have these types of qualitative research goals. The interviews were designed to capture organizations' viewpoints regarding C-SCRM key practices. Interview questions were developed and refined based on the expertise of Supply Chain Risk Management experts at NIST and Boston Consulting

Group (BCG).

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 117 [Docket ID: DOD-2020-OS-0045] RIN 0790-AK85 AGENCY: Office of the Under Secretary of Defense for Intelligence & Security, Department of Defense (DoD). ACTION: Final rule with request for comment. SUMMARY: The Department of Defense (DoD) is codifying the National Industrial Security Program Operating Manual (NISPOM) in regulation. The NISPOM establishes requirements for the protection of classified information disclosed to or developed by contractors, licensees, grantees, or certificate holders (hereinafter referred to as contractors) to prevent unauthorized disclosure. In addition to adding the NISPOM to the Code of Federal Regulations (CFR), this rule incorporates the requirements of Security Executive Agent Directive (SEAD) 3, Reporting Requirements for Personnel with Access to Classified Information or Who Hold a Sensitive Position. SEAD 3 requires reporting by all contractor cleared personnel who have been granted eligibility for access to classified information. This NISPOM rule provides for a single nation-wide implementation plan which will, with this rule, include SEAD 3 reporting by all contractor cleared personnel to report specific activities that may adversely impact their continued national security eligibility, such as reporting of foreign travel and foreign contacts. NISP Cognizant Security Agencies (CSAs) shall conduct an analysis of such reported activities to determine whether they pose a potential threat to national security and take appropriate action. Finally, the rule also implements the provisions of Section 842 of Public Law 115-232, which removes the requirement for a covered National Technology and Industrial Base (NTIB) entity operating under a special security agreement pursuant to the NISP to obtain a national interest determination as a condition for access to proscribed information. DATES: Effective date: This rule is effective February 24, 2021. Comments must be received by February 19, 2021. ADDRESSES: You may submit comments, identified by docket number and/or Regulatory Information Number (RIN) and title, by any of the following methods: Federal Rulemaking Portal: <http://www.regulations.gov>. Follow the instructions for submitting comments. Mail: DoD cannot receive written comments at this time due to the COVID-19 pandemic. Comments should be sent electronically to the docket listed above. Instructions:

(b) The Director, Defense Security Service (DSS), in addition to the responsibilities in paragraph (d) of this section, under the authority, direction, and control of the USD(I) will in accordance with DoD Instruction 5220.22, National Industrial Security Program (available at <http://www.dtic.mil/whs/directives/corres/pdf/522022p.pdf>). (1) Make FOCI determinations on a case-by-case basis for U.S. contractors or companies under consideration for an FCL under the NISP. (2) Collect information necessary to examine the source, nature, and extent of a company's ownership, control, or influence by foreign interests. (3) Determine, on behalf of the GCAs, whether a U.S. company is under FOCI to such a degree that the granting of an FCL would be inconsistent with the U.S. national security interests. (4) Determine the security measures necessary to negate or mitigate FOCI and make recommendations to the U.S. company and to those GCAs with a contractual interest or other equity in the matter. (5) Provide GCAs a guide to clarify their roles and responsibilities with respect to the FOCI process and to national interest determinations (NIDs), in particular. Update the guide, as needed, in coordination with the Office of the Under Secretary of Defense for Intelligence (OUSD(I)) Security Directorate. (6) Determine a U.S. company's eligibility for an FCL on an initial and continuing basis depending on recurring security reviews and other interactions. (7) Develop proposed changes to maintain the currency and effectiveness of this part. Forward proposed changes and associated justification to the OUSD(I) Security Directorate for consideration as future changes to this part. (8) Consider and, as warranted, approve requests for exception to DoD 5220.22-M in consultation with affected GCAs for specific contractors and for specific periods of time (such as, to the completion date of a contract) when a contractor is unable to comply with the requirements of DoD 5220.22-M. Consideration of such requests will include an evaluation of any proposed alternative procedures with supporting justification and coordination as applicable, consistent with paragraph (a)(4) of this section. (9) Coordinate and receive the concurrence of the OUSD(I) Security Directorate on requests for exception to DoD 5220.22-M and consistent with paragraph (a)(4) of this section when any of the following provisions apply: (i) The request exceeds the authority of the Director, DSS

as defined in this section; (printed page 19472) (ii) The proposed exception applies to more than one contractor location; or, (iii) The exception would be contrary to U.S. national policy or international agreements, including those relating to foreign government information (FGI) and international issues under the cognizance of the USD(P) with coordination as applicable, consistent with paragraph (a)(4) of this section.

(Comment 40) One comment asserts that there is no added public health protection from requiring retailers to establish and maintain records of the immediate previous holder of a food product. The proposed rule ensures that all information desired by FDA (e.g., the product and lot number going to a particular retail store) is already recorded by both the distributor of the product and by the transporter of the product. Therefore, traceability of a product will exist without requiring the retailer to also keep that information. The comment believes that the added burden of requiring retailers to establish and maintain records on immediate previous sources of the food it receives is not necessary based on the limited public health and safety benefit that would result. (Response) As discussed in response to comment 37 of this document, the Bioterrorism Act did not exempt retail food establishments from recordkeeping requirements. FDA decided to exclude persons who distribute food directly to consumers from the requirement to establish and maintain records of subsequent recipients because sick consumers can provide information as to where they obtained food in a traceback, and FDA can notify consumers of a food threat in a trace forward. In the case of a traceback from a retailer, the retailer's records of the immediate previous sources are needed by FDA to address credible threats of serious adverse health consequences or death to humans or animals. In a traceback, it is unlikely that a retailer's source for certain foods would be apparent. Accordingly, in order for FDA to be able to identify the retailer's immediate previous nontransporter and transporter sources, to gain access to those sources records and identify its sources or other recipients of the food, the retailer has to have records identifying those sources. Therefore, the final rule requires retailers to establish (printed page 71577) and maintain records containing this information. However, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements in subpart J of the final rule, except §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.)

to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided to the President and others are not compromised, to protect records used solely as statistical records, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (27) System identifier and name. A0381-100a DAMI, Intelligence/Counterintelligence Source Files. (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958 , as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (D) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(1) , (k)(2), or (k)(5) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(1) , (k)(2), and (k)(5). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the

nature of that investigation which will present a serious impediment to law enforcement.

(e) NIST SP 800-53, titled "Security and Privacy Controls for Information Systems and Organizations," Revision 5 (NIST SP 800-53 R5), provides a catalog of security and privacy controls for information systems and organizations to protect organizational operations and assets, individuals, other organizations, (printed page 83098) and the Nation from a diverse set of threats and risks, including hostile attacks, human errors, natural disasters, structural failures, foreign intelligence entities, and privacy risks. The controls are flexible and customizable and implemented as part of an organization-wide process to manage risk. The controls address diverse requirements derived from mission and business needs, laws, executive orders, directives, regulations, policies, standards, and guidelines. Finally, the consolidated control catalog addresses security and privacy from a functionality perspective (i.e., the strength of functions and mechanisms provided by the controls) and from an assurance perspective (i.e., the measure of confidence in the security or privacy capability provided by the controls). Addressing functionality and assurance helps to ensure that information technology products and the systems that rely on those products are sufficiently trustworthy. This document is incorporated by reference as a source for definitions. (f) NIST SP 800-82r3, titled "Guide to Operational Technology (OT) Security," September 2023 (NIST SP 800-82r3), provides guidance on how to secure ICS, including Supervisory Control and Data Acquisition (SCADA) systems, Distributed Control Systems (DCS), and other control system configurations such as Programmable Logic Controllers (PLC), while addressing their unique performance, reliability, and safety requirements. The document provides an overview of ICS and typical system topologies, identifies typical threats and vulnerabilities to these systems, and provides recommended security countermeasures to mitigate the associated risks. This document is incorporated by reference as a source for definitions.

The Renewable Energy Company recommends that companies interested in maturing or developing new C-SCRM programs should focus on uplifting the cyber hygiene practices of their vendors. Instead of focusing exclusively on manufacturing or logistics processes, companies and vendors should work together to improve their entire security posture, allowing them to fully appreciate and benefit from mechanisms such as multi-factor authentication and logical segmentation.

OMB collection requirements. If information is to be collected from members of the public, the requirements of reference () apply and OMB must be advised. 10. Supporting documentation. The following are typical enclosures that may be required: a. An advance copy of the system notice for a new or altered system that is proposed for publication. b. An advance copy of a proposed exemption rule if the new or altered system is to be exempted in accordance with subpart F. c. Any other supporting documentation that may be pertinent or helpful in understanding the need for the system or clarifying its intended use. Attachment 2-SAMPLE NARRATIVE STATEMENT DEPARTMENT OF DEFENSE Office of the Secretary Narrative Statement on a New System of Records Under the Privacy Act of 1974 1. System identifier and name: NSLRB 01, entitled "The National Security Labor Relations Board (NSLRB)." 2. Responsible official: Mr. John Miller, National Security Labor Relations Board (NSLRB), 0000 Smith Boulevard, Arlington, VA 22209, Telephone (703) 000-0000. 3. Purpose of establishing the system: The Office of the Secretary of Defense is proposing to establish a system of records that will document adjudication of unfair labor practice charges, negotiability disputes, exceptions to arbitration awards, and impasses filed with the National Security Labor Relations Board. 4. Authority for the maintenance of the system: The National Defense Authorization Act for FY 2004, Pub Law 108-136 , Section 1101; 5 U.S.C. 9902(m) , Labor Management Relations in the Department of Defense; and 5 CFR 9901.907 , National Security Labor Relations Board. 5. Probable or potential effects on the privacy of individuals: None 6. Is the system, in whole or in part, being maintained by a contractor? No 7. Steps taken to minimize risk of unauthorized access: Records are maintained in a controlled facility. Physical entry is restricted by the use of locks, guards, and is accessible only to authorized personnel. Access to records is limited to person(s) responsible for servicing the record in performance of their official duties and who are properly screened and cleared for need-to-know. Access to computerized data is restricted by passwords, which are changed periodically. 8. Routine use compatibility: Any release of information contained in this system of records outside of the DoD will be compatible with purposes for which the information is collected and maintained. The DoD "Blanket Routine Uses" apply to this system of records. 9. OMB information collection requirements: None. 10. Supporting documentation: None. Appendix G to Part 310-Sample Amendments or Deletions to System Notices in Federal Register Format (See §.310.34) (printed page 18789) Amendment of system

notice DEPARTMENT OF DEFENSE Department of the Army Privacy Act of 1974; System of Records
AGENCY: Department of the Army, DoD. ACTION: Notice to Amend a System of Records. SUMMARY:

IoT devices are acquired and used by many customers: individuals, companies, government agencies, educational institutions, and other organizations. Unfortunately, IoT devices often lack device capabilities that customers can use to help mitigate their cybersecurity risks, such as the functionality customers routinely expect their desktop and laptop computers, smartphones, tablets, and other IT devices to have. Consequently, IoT device customers may have to select, implement, and manage additional or new cybersecurity controls or alter the controls they already have. Compounding this task, customers may not know they need to alter their existing processes to accommodate the unique characteristics of IoT. The result is many IoT devices are not secured in the face of evolving threats; therefore, attackers can more easily compromise IoT devices and use them to harm device customers and conduct additional nefarious acts (e.g., distributed denial of service [DDoS] attacks) against other organizations. 1. Which types of people are expected customers for this device? (e.g., musicians, small business owners, cyclists, police officers, chefs, home builders, preschoolers, electrical engineers) 2. Which types of organizations are expected customers for this device? (e.g., individual home users, small retail businesses, large hospitals, energy companies with solar farms, educational institutions with buses) The core baseline is just one set of device cybersecurity capabilities that may be needed in an IoT device, and manufacturers should consult other sources to derive or identify appropriate device cybersecurity capabilities and implementations for expected customers and use cases, as discussed in Section 3.2. Manufacturers can follow a process of linking cybersecurity mitigation, needs, and goals with specific device cybersecurity capabilities.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 A condition that results from the establishment and maintenance of protective measures that enable an 3069

(vi) DSS will review and consider the FOCI action plan itself, the factors identified in paragraph (b)(3)(i) of this section, and any threat or risk assessments or other relevant information. If an action plan is determined to be unacceptable, DSS can recommend and negotiate an acceptable action plan including, but not limited to, the measures identified in paragraphs (b)(4)(ii) and (b)(4)(iii) of this section. In any event, DSS will provide written feedback to a company or the company's designated representative on the acceptability of the FOCI action plan within 30 calendar days of receipt. (4) Options To Address FOCI. (i) Under all FOCI action plans, management positions requiring PCLs in conjunction with the FCL must be filled by eligible U.S. citizens residing in the United States in accordance with DoD 5220.22-M. (ii) When factors related to foreign control or influence are present, but unrelated to ownership, the plan must provide positive measures that assure that the foreign interest can be effectively denied access to classified information and cannot otherwise adversely affect performance on classified contracts. Non-exclusive examples of such measures include: (A) Adoption of special board resolutions. (B) Assignment of specific oversight duties and responsibilities to independent board members. (C) Formulation of special executive-level security committees to consider and oversee matters that affect the performance of classified contracts. (D) The appointment of a technology control officer. (E) Modification or termination of loan agreements, contracts, and other understandings with foreign interests. (F) Diversification or reduction of foreign-source income. (G) Demonstration of financial viability independent of foreign interests. (printed page 19474) (H) Elimination or resolution of problem debt. (I) Physical or organizational separation of the contractor component performing on classified contracts. (J) Other actions that negate or mitigate foreign control or influence. (iii) FOCI concerns related to foreign ownership of a company or corporate family arise when a foreign interest has the ability, either directly or indirectly, whether exercised or exercisable, to control or influence the election or appointment of one or more members to the company's governing board (e.g., Board of Directors, Board of Managers, or Board of Trustees) or its equivalent, by any means. Some methods that may be applied to mitigate the risk of foreign ownership are outlined in DoD 5220.22-M and further described in this section. While these methods are mentioned in relation to specific ownership and control thresholds, these descriptions should not be construed as DoD-sanctioned criteria mandating the selection or acceptance of a certain FOCI action plan. DSS retains the authority to reject or modify any proposed FOCI action plan in consultation with the affected GCAs. (A) Board Resolution.

(1) The Contractor shall implement and maintain security and privacy safeguards and controls with the security level and services required in accordance with the Federal Risk and Authorization Management Program (FedRAMP) authorization level specified. (i) Cloud continuous monitoring requirement. The Contractor shall engage in continuous monitoring activities and provide continuous monitoring deliverables as required for FedRAMP approved capabilities (see FedRAMP Continuous Monitoring Strategy Guide). (ii) Cryptographic key services. The Government reserves the right to implement and operate its own cryptographic key management, key revocation and key escrow services. (2) For cloud computing services required to meet FIPS Publication 199 high impact requirements, the Contractor shall maintain within the United States and its outlying areas (see FAR 2.101) all Government data that is not physically located on U.S. Government premises, unless otherwise specified in the contract. (d) Limitations on access to, and use and disclosure of, Government data and Government-related data. (1) The Contractor shall not access, use, or disclose Government data or Government-related data unless specifically authorized under the contract or task or delivery order or in writing by the Contracting Officer. (i) When authorized, any access to, or use or disclosure of, Government data or Government-related data shall only be for purposes specified in the contract or task order or delivery order. (ii) The Contractor shall ensure that its employees are subject to all such access, use, and disclosure prohibitions and obligations of this paragraph. (iii) The access, use, and disclosure prohibitions and obligations of this paragraph shall survive the expiration or termination of this contract. (2) The Contractor shall use Government-related data only to manage the operational environment that supports the Government data and for no other purpose unless otherwise permitted with the prior written approval of the Contracting Officer. (e) Notifiable incident reporting, incident response and threat reporting. For contract coverage on security incident and cyber threat reporting, see FAR clause 52.239-ZZ, Incident and Threat Reporting and Incident Response Requirements for Products or Services Containing Information and Communications Technology, in this contract. (f) Records management and Government access. (1) The Contractor shall provide the Contracting Officer with all Government data and Government-related data in the format specified in the contract. (2) The Contractor shall dispose of Government data and Government-related data in accordance with the terms of the contract and provide the confirmation of disposition to the Contracting Officer in accordance with contract closeout procedures. (3)(i) To the extent required to carry out a program of inspection to safeguard against threats and hazards to the security, (i.e.,

We assume that a 10-day reduction in the duration of the traceback component of an outbreak investigation would reduce the time required to take an initial preventive action by 10 days as well. A savings of 10 days would reduce the average amount of time required to take a preventive action to 68 days (based on the estimated current time of 78 days), and a savings of 5 days would reduce the time required to take a preventive action to 73 days. From data used to generate the cumulative distribution displayed earlier in this document in figure 2 entitled ‘Cumulative Distribution of the Fraction of Total Illnesses by Outbreak Duration (2000-2003),’ we find that between 15 and 18 percent of all outbreak victims became ill from outbreaks that lasted more than 65 days. Consequently, the benefits from (printed page 71629) reducing traceback times by either 10 days for the 4-and 8-hour records access requirement, or 5 days for the 24-hour records access requirement can be considerable. We assume that with comprehensive coverage, the number of traceback investigations that are prematurely terminated because of poor records quality will fall to zero under either the 24-hour records access requirement, or under the proposed 4-and 8-hour records access requirement. The reduced durations of traceback investigations computed in the previous paragraphs are based on the assumed comprehensive coverage of the proposed recordkeeping rule. Excluding certain persons from all or part of the requirements of the regulation results in a reduction in the benefits as measured by reduced times for traceback investigations. The extent of the reduction in benefits from reduced traceback durations depends on the number of persons (and facilities for which the persons are responsible) that may be excluded from the regulation and the position along the supply chain of the excluded facilities. The position along the supply chain influences the probability of contamination, as well as the probability of losing the paper trail. We assess the relative benefits of excluding certain sectors as policy options later in this document. Finally, if there is a deliberate attack on the food supply, with catastrophic consequences, then the duration of the preliminary and decision making parts of the outbreak investigation will likely be substantially compressed, and the importance of the traceback investigation in preventing additional illnesses from an outbreak will be elevated. If firms fully understand the seriousness of an outbreak, their reaction times may be compressed as well, which would tend to reduce the computed benefits from this rule. However, we expect FDA to be more likely

than all firms to fully understand the seriousness of an outbreak.

It is estimated that the costs to perform an initial and annual affirmation of compliance with CMMC Level 1 for an other than small entity is \$584 A director (MGMT5) for 2 hours ($\$190.52/\text{hr} \times 2\text{hrs} = \381) A staff IT specialist (IT4) for 2.08 hours ($\$97.49/\text{hrs} \times 2.08\text{hrs} = \203) The Level 1 self-assessment and affirmations cost burden will be addressed as part of the 48 CFR part 204 CMMC Acquisition rule. Summary: The following is the annual other than small entities total cost summary for Level 1 self-assessments and affirmations over a ten-year period: (Example calculation, Year 1: $\$4,042$ per entity $\times 246$ entities (cumulative) = $\$994,233$) Small Entities Nonrecurring and recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with CMMC Level 1 since it is assumed the contractor or subcontractor has implemented the applicable security requirements. [47] Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 1 self-assessment and affirmation is $\$5,977$ (as summarized in 4.1.2, table 10). A Level 1 self-assessment is conducted annually, and is based on the assumptions detailed: Phase 1: Planning and preparing for the self-assessment: $\$1,803$ A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) An external service provider (ESP) for 4 hours ($\$260.28 \times 4\text{hrs} = \$1,041$) Phase 2: Conducting the self-assessment: $\$2,705$ A director (MGMT5) for 6 hours ($\$190.52/\text{hr} \times 6\text{hrs} = \$1,143$) An external service provider (ESP) for 6 hours ($\$260.28 \times 6\text{hrs} = \$1,562$) Phase 3: Reporting of assessment results into SPRS: $\$909$ A director (MGMT5) for 2 hours ($\$190.52/\text{hr} \times 2\text{hrs} = \381) An external service provider (ESP) for 2 hours ($\$260.28/\text{hr} \times 2\text{hrs} = \521) A staff IT specialist (IT4-SB) for 0.08 hours 48 ($\$86.24/\text{hr} \times 0.08\text{hrs} = \7) Affirmation: initial affirmation post assessment: $\$560$ Reaffirmations: It is estimated that the costs to reaffirm a CMMC Level 1 annually for a small entity is $\$560$ A director (MGMT5) for 2 hours ($\$190.52/\text{hr} \times 2\text{hrs} = \381) A staff IT specialist (IT4-SB) for 2.08 hours ($\$86.24/\text{hr} \times 2.08\text{hrs} = \179) The Level 1 self-assessment and affirmations cost burden will be addressed as part of the 48 CFR part 204 CMMC Acquisition rule. Summary: The following is the annual small entities total cost summary (printed page 83182) for Level 1 self-assessments and affirmations over a ten-year period: (Example calculation, Year 1: $\$5,977$ per entity $\times 699$ entities (cumulative) = $\$4,177,845$) All Entities Summary The following is a summary of the combined costs for both small and other than small entities for Level 1 self-assessments and affirmations over a ten-year period: CMMC Level 2 Self-Assessment and Affirmation Costs Other Than Small Entities Nonrecurring and Recurring Engineering Costs: There are no nonrecurring or recurring engineering costs associated with Level 2 self-assessment since it is assumed the contractor or subcontractor has implemented the NIST SP 800-171 R2 security requirements.

includes provisions for the DOE with regard to privately generated RD, whereby the DOE may classify such information in accordance with the AEA. (g) Improperly released classified information appearing in public media. Improperly released classified information is not automatically declassified. When classified information has been improperly released, and even when that classified information has become publicly available, contractors will: (1) Continue to protect the information at the appropriate classification level until formally advised to the contrary by the GCA. (2) Bring any questions about the propriety of continued classification in these cases to the immediate attention of the GCA. (3) Notify the applicable CSA if an employee downloads the improperly released classified information to determine how to resolve a data spill. (h) Downgrading or declassifying classified information. Information is downgraded or declassified based on the loss of sensitivity of the information due to the passage of time or on occurrence of a specific event. Downgrading or declassifying actions constitute implementation of a directed action based on a review by either the OCA or the USG-designated classification authority. Declassification is not an approval for public disclosure. (1) Downgrading. Contractors will refer information for classification or downgrade to the GCA based on the guidance provided in a contract security classification specification, or equivalent, or upon formal notification. (2) Declassification. Contractors are not authorized to implement downgrading or declassification instructions even when the material is marked for automatic downgrading or declassification. If the material is marked for automatic declassification and the contractor notes that the date or event for the automatic declassification has occurred, the contractor will seek guidance from the GCA. (i) RD, FRD, and TFNI. Protection requirements for RD, FRD, and TFNI are pursuant to § 117.23(e). Information about classification and declassification of RD, FRD, or TFNI documents is in § 117.23(e)(5). § 117.14 Marking requirements. (a) Purpose for marking. (1) Physically marking classified information with appropriate classification markings serves to warn and inform holders of the information of the degree of protection required. Other notations facilitate downgrading and declassification, and aid

in derivative classification actions. (2) Contractors will clearly mark all classified information and material to convey to the holder the level of classification assigned, the portions that contain or reveal classified information, the period of time protection is required, the identity (by name and position or personal identifier) of the classifier, the source(s) for derivative classification, and any other notations required for protection of the information. (b) Marking guidance for classified information and material. Contractors will use the marking guidance conveyed in 32 CFR 2001.22 through 2001.26

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary [Docket ID: DOD-2018-OS-0008] RIN 0790-AJ20 32 CFR Part 310 AGENCY: Department of Defense. ACTION: Final rule. SUMMARY: The Department of Defense (DoD) is revising its Privacy regulation to implement the Privacy Act of 1974, as amended. The rule conforms to the requirements of the Office of Management and Budget Circular A-108, December 23, 2016. This part establishes and promotes uniformity in the DoD Privacy Program, creating a single privacy rule for the Department, while incorporating other administrative changes. It takes precedence over all DoD component publications that supplement and implement the DoD Privacy program. Subsequently, DoD plans to remove individual component Privacy Program rulemakings, given that the individual component exemption rules have been incorporated into this rule. DATES: This final rule is effective on May 13, 2019. FOR FURTHER INFORMATION CONTACT: Cindy Allard, (703) 571-0086. SUPPLEMENTARY INFORMATION: The DoD is revising 32 CFR part 310 to implement section 552a of Title 5, United States Code, thus establishing procedures for access and other Privacy Act protections. It supersedes the current parts 310 through 329 and parts 505, 701, and 806b to promote uniformity in the DoD Privacy program and streamline the existing rules. The existing system of records exemption rules that have been promulgated in accordance with the requirements of 5 U.S.C. 553(b)(1) , (2), and (3), (c) and (e) and published in parts 310 through 329 and parts 505, 701, and 806b remain effective; however, for streamlining and ease of use for the reader we are moving the existing exemption rules from parts 311 through 329 and parts 505, 701, and 806b into part 310 without amendment. Repeal of the individual DoD Component Privacy rules will be published in the Federal Register after this rule is effective. This rule conforms to the requirements of the Office of Management and Budget Circular A-108, 'Federal Agency Responsibilities for Review, Reporting, and Publication under the Privacy Act,' dated December 23, 2016, which can be found at https://www.whitehouse.gov/sites/whitehouse.gov/files/omb/circulars/A108/omb_circular_a-108.pdf , and Office of Management and Budget Circular A-130, 'Managing Information as a Strategic Resource,' dated July 28, 2016, which can be found at <https://www.whitehouse.gov/sites/whitehouse.gov/files/omb/circulars/A130/a130revised.pdf> .

In addition, as explained further in response to comment 13, intra-company transfers of food are not subject to additional recordkeeping requirements. Once a covered person (including individuals, partnerships, corporations, and associations) receives food and keeps information on its immediate previous sources, that person or company does not need to keep additional records until it releases the food to another person or company. Unless otherwise exempt, at the time that person or company releases the food, it is required to identify the immediate subsequent recipients of that food. 9. Nontransporter Immediate Previous Source There were no comments on this issue. (printed page 71589) 10. Nontransporter Immediate Subsequent Recipient There were no comments on this issue. 11. Perishable Food (Comment 72) Several comments propose that FDA use existing National Institute of Standards and Technology (NIST) Handbook 130 Regulations for Uniform Open Dating Definition for Perishable; Semi-Perishable and Long Term Shelf Life to define 'perishable food.' One comment states that the definition of 'perishable food' proposed by FDA is inconsistent with prevailing regulatory definitions of that term. The NIST Handbook defines 'perishable food' as 'any food for which a significant risk of spoilage, loss of value, or loss of palatability occurs within 60 days of the date of packaging.' 'Semi-Perishable food' means 'any food for which a significant risk for spoilage, loss of value, or loss of palatability occurs only after a minimum of 60 days, but within 6 months, after the date of packaging.' 'Long Shelf-Life food' is defined as 'any food for which a significant risk of spoilage, loss of value, or loss of palatability does not occur sooner than six months after the date of packaging, including foods preserved by freezing, dehydrating, or being placed in a hermetically sealed container.' These definitions have a history of use and acceptance

by industry and government, and were developed 30 years ago by the National Conference of Weights and Measures, working in conjunction with state agencies responsible for the regulation of foods. The comments note that the National Conference undertook this task to assist in the establishment of a uniform method for presenting open code date labeling for foods. The definitions have since been adopted by numerous states and local jurisdictions with open date code regulations.

According to Cryptographic Key Management Workshop Summary -- June 8-9, 2009, 2.4.3 Cryptographic Key Management Framework: Miles Smid, Orion Security: CKM solution. In addition, the key management policies for all key types and related keying material over the key management lifecycle need to be consistent with the overall data protection policies. - In order to ensure that the CKM solution provides adequate support for the application, the framework needs to define necessary inputs regarding the unique requirements or constraints that are imposed by the application or the organization performing it. For example, input should include the desired target security strength for the managed information, the assurances that the CKM solution must meet to achieve the target security strength, and how conformance of the implementation to the CKM solution is to be verified. - CKM components from the framework must be selected to support the specified organizational and application policies, requirements and constraints. CKM components include keys, algorithms, primitives, and protocols. Components may also include modules, products, and even the combination or composition of other components in an innovative manner to provide a secure CKM solution. - For interoperability, certain interfaces will need to be specified. Possible interfaces include: the cryptographic algorithm interface, the key management interface, the cryptographic module interface, the product interface, and the application interface. In general, only the interfaces that are used by entities outside the application need to be specified. - Finally, the framework should encourage a CKM solution developer to think about future transitions. When will the CKM solution need maintenance, when will it need to be replaced, and how might it best be phased out? These questions are usually overlooked by today's CKM solutions. As a result, it is often considered preferable to live with an insecure CKM solution, than to suffer the pain of replacing it. - Frameworks can be strong supporting structures.

(g) NIST SP 800-115, titled "Technical Guide to Information Security Testing and Assessment," September 2008 (NIST SP 800-115 Sept2008), assists organizations in planning and conducting technical information security tests and examinations, analyzing findings, and developing mitigation strategies. The guide provides practical recommendations for designing, implementing, and maintaining technical information security test and examination processes and procedures. These can be used for several purposes, such as finding vulnerabilities in a system or network and verifying compliance with a policy or other requirements. The guide is not intended to present a comprehensive information security testing and examination program but rather an overview of key elements of technical security testing and examination, with an emphasis on specific technical techniques, the benefits and limitations of each, and recommendations for their use. This document is incorporated by reference as a source for definitions. (h) NIST SP 800-160, Volume 2, titled "Developing Cyber-Resilient Systems: A Systems Security Engineering Approach," Revision 1, December 2021 (NIST SP 800-160 V2R1), focuses on cyber resiliency engineering—an emerging specialty systems engineering discipline applied in conjunction with systems security engineering and resilience engineering to develop survivable, trustworthy secure systems. Cyber resiliency engineering intends to architect, design, develop, implement, maintain, and sustain the trustworthiness of systems with the capability to anticipate, withstand, recover from, and adapt to adverse conditions, stresses, attacks, or compromises that use or are enabled by cyber resources. From a risk management perspective, cyber resiliency is intended to help reduce the mission, business, organizational, enterprise, or sector risk of depending on cyber resources. This document is incorporated by reference as a source for definitions.

proprietary business information), the contracting officer shall determine whether the information must be marked and protected in accordance with applicable law, policy, guidance, and agency procedures. Individuals who are unsure how to handle such information should consult with agency officials as necessary. (d) Except as provided in paragraph (d)(3) of this section, the contracting officer must promptly notify the offeror or contractor in writing if the contracting officer believes that contractor proprietary business information, contractor-attributional information, contractor bid or proposal information, or information marked in accordance with 52.215-1(e) has been inappropriately marked. Notification should occur upon discovery and may be made prior to award. The offeror or contractor that has affixed the marking must be given an opportunity to

justify the marking. (1) If the offeror or contractor agrees that the marking is not justified or does not respond within the time specified in the notice, the contracting officer may remove the marking and release the information. (2) If, after reviewing the contractor's justification, the contracting officer determines that the marking is not justified, the contracting officer must notify the offeror or contractor in writing before releasing the information. (3) For technical data marked as proprietary by an offeror or contractor, the contracting officer must follow the procedures in 27.404-5. * * * * PART 4-ADMINISTRATIVE AND INFORMATION MATTERS 5. Revise the heading of subpart 4.4 to read as follows: Subpart 4.4-Safeguarding Information and Information Systems 6. Add section 4.401 to read as follows: 4.401 Definition. Information, as used in this subpart, means any communication or representation of knowledge such as facts, data, or opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, electronic, or audiovisual forms (see Office of Management and Budget (OMB) Circular A-130). 4.402 [Redesignated as 4.402-1] 7. Redesignate section 4.402 as section 4.402-1. 8. Add section 4.402 to read as follows: 4.402 Classified information. 4.403 [Redesignated as 4.402-2]. 9. Redesignate section 4.403 as section 4.402-2. 10. Amend the newly redesignated section 4.402-2 by: a. Revising paragraphs (b)(2)(i) and (ii); and b. Removing from paragraph (c)(1) the reference ·4.402(d)(1)· and adding ·4.402-1(d)(1)· in its place. The revisions read as follows: 4.402-2 Responsibilities of contracting officers. * * * * (b) * * * (2) * * * (i) An appropriate Security Requirements clause in the solicitation (see 4.402-3(a)); and (ii) As appropriate, in solicitations and contracts when the contract may require access to classified information, a requirement for security safeguards in addition to those provided in the clause 52.204-2, Security Requirements for Classified Information. * * * * 11. Add sections 4.402-3, and 4.403 through 4.403-7 to read as follows: 4.402-3 Contract clause.

(Response) ·Direct sellers· are not required to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients for sales directly to consumers. Direct sellers that qualify as a retail food establishment under §1.327(e) are required to establish and maintain records for sales to other direct sellers, when such information is reasonably available. FDA explains the rationale for distinguishing between sales to consumers and businesses in response to comment 40. Direct sellers, like other covered persons, are required to establish and maintain records to identify the nontransporter and transporter immediate previous sources of food, as required by §1.337 of this final rule. However, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements of subpart J in this final rule, except the record access provisions for existing records under §§1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) Thus, if a direct seller qualifies as a retail food establishment and employs 10 or fewer full-time equivalent employees, it is exempt from all recordkeeping requirements under this rule, except for the record access provisions for existing records. (Comment 51) One comment states the Secretary has the full discretion to determine who shall be required to maintain records and what records shall be kept. Congress has clearly communicated its intention to protect small businesses by stating: ·The Secretary shall take into account the size of the business in promulgating regulations under this section.· The comment states that individual direct sellers who distribute nutritional or related products should be exempt from the requirement to maintain records under the proposed rule. (Response) As stated in the proposed rule, FDA carefully considered the size of a business when developing these regulations. FDA found that most products and ingredients pass through (printed page 71581) at least one very small business when moving through the distribution process. If FDA were to exempt all very small businesses with 10 or fewer employees, not just those in the retail sector, this would create a ·Swiss Cheese· approach to trace back, as there would be a potential failure of entities to keep records throughout the distribution chain. The number of very small entities account for a large fraction of the total number of food establishments. We used U.S. Census data to estimate the percentage of the total number of food establishments that are very small, as well as their revenues, by sector and report them in table A of this document. The fraction of the total number of facilities that are very small ranges from an estimated 73 percent of convenience outlets to 90 percent of transporters. Table A.·Estimated Total Number of Very Small Food Establishments Sector

Both approaches involve a combination of hardware-based, or physical, TPM and a softwarebased vTPM (virtual TPM). The difference between the two approaches is in the location where vTPM is placed in the container stack. The security solution where vTPM is placed in the Linux kernel is discussed in section 3.1, and the solution where vTPM is placed in a dedicated container is the topic of section

3.2.

(1) Certain documents under the physical control of DoD personnel and used to assist them in performing official functions, are not considered "Agency records" within the meaning of this part. Uncirculated personal notes and records that are not disseminated or circulated to any person or organization (for example, personal telephone lists or memory aids) that are retained or discarded at the author's discretion and over which the Component exercises no direct control are not considered Agency records. However, if personnel are officially directed or encouraged, either in writing or orally, to maintain such records, they may become "Agency records," and may be subject to this part. (2) The personal uncirculated handwritten notes of unit leaders, office supervisors, or military supervisory personnel concerning subordinates are not systems of records within the meaning of this part. Such notes are an extension of the individual's memory. These notes, however, must be maintained and discarded at the discretion of the individual supervisor and not circulated to others. Any established requirement to maintain such notes (such as, written or oral directives, regulations, or command policy) may transform these notes into "Agency records" and they then must be made a part of a system of records. If the notes are circulated, they must be made a part of a system of records. Any action that gives personal notes the appearance of official Agency records is prohibited, unless the notes have been incorporated into a system of records. (i) Relationship between the Privacy Act (5 U.S.C. 552a) and the FOIA (5 U.S.C. 552). Not all requesters are knowledgeable of the appropriate statutory authority to cite when requesting records. In some instances, they may cite neither Act, but will imply one or both Acts. The below guidelines are provided to ensure requesters are given the maximum amount of information as authorized under both statutes. (1) Process requests for individual access as follows: (i) If the records are required to be released under the Privacy Act, the FOIA (32 CFR part 286) does not bar release even if a FOIA exemption could (printed page 18768) be invoked if the request had been processed solely under FOIA. Conversely, if the records are required to be released under the FOIA, the Privacy Act does not bar disclosure. (ii) Requesters who seek records about themselves contained in a Privacy Act system of records, and who cite or imply only the Privacy Act, will have their records processed under the provisions of this part and the FOIA (32 CFR part 286). If the system of records is exempt from the access provisions of this part, and if the records, or any portion thereof, are exempt under the FOIA, the requester shall be advised and informed of the appropriate Privacy and FOIA exemption. Only if the records can be denied under both statutes may the Department withhold the records from the individual. Appeals shall be processed under both Acts.

From the NIST SP 800-172 Rev 3 Final Public Draft: The benefit of periodic refreshes of system components and services is that it does not require organizations to determine in advance whether compromises have occurred, NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 which may be difficult or impossible. The refresh of selected system components 2323

Adoption of health IT that is certified through the ONC Health IT Certification Program as meeting the proposed MFA criterion, should the proposal be finalized, may contribute to a regulated entity's compliance with the proposed implementation specification for MFA in this NPRM. Under proposed 45 CFR 164.312(f)(2)(ii)(B) , a regulated entity would be required to deploy MFA for any action that would change a user's privileges to the regulated entity's relevant electronic information systems in a manner that would alter the user's ability to affect the confidentiality, integrity, or availability of ePHI. These modified privileges may provide a user with a level of access inconsistent with a regulated entity's policies and procedures and increase the risk to ePHI by affording a user who does not need to have access to certain systems or information the opportunity to remove security measures deployed to protect ePHI. Because a user may affect the confidentiality, integrity, or availability of ePHI by accessing a relevant electronic information system, a regulated entity would be expected to (printed page 975) deploy MFA for changed privileges in both types of systems. Similar to the proposed standard for encryption, the Department proposes three exceptions at proposed 45 CFR 164.312(f)(2)(iii) to the proposed specific requirement to implement MFA. The first proposed exception at proposed 45 CFR 164.312(f)(2)(iii)(A) would be for a technology asset that does not support MFA but is currently in use by a regulated entity. Because the requirements for authentication under the existing Security Rule today do not expressly refer to MFA, a regulated entity that is not using MFA to meet the requirement to authenticate user identities may argue that it is in compliance with the authentication standard without using MFA. The Department recognizes that it may take some time for a regulated entity to adopt compliant

software or hardware, and thus we propose an exception where such software or hardware does not support MFA. To meet this exception, a regulated entity would be required to establish a written plan to migrate ePHI to technology assets that supports MFA and to actually migrate the ePHI to such technology assets in accordance with the written plan. Accordingly, a regulated entity would be required to establish the plan, implement the plan, and actually migrate ePHI to technology assets that supports MFA within a reasonable and appropriate period of time. For example, it would not be reasonable and appropriate for a regulated entity to establish a plan to migrate to a new practice management system that supports MFA and fail to take any steps to perform the migration for an entire year. Applying the standard flexibly and at scale, a reasonable and appropriate timeframe for a system with 5,000 users may be different than one for a solo practitioner; however, both entities would be expected to progress to completion.

the United Service Organizations (USO). If any one of the above criteria is met, all employees engaged in such employment, regardless of nationality (including U.S. citizens and residents, host country nationals (local hires), and third country nationals (individuals hired from another country to work in the host country)), are covered under the Act. Comment: Requirements jeopardize NGO security posture Response: This Rule applies only to personnel performing private security functions under a covered contract. A covered contract is defined by Section 864(a)(3) of the FY 2008 NDAA, as amended by Section 813(b) of the FY 2010 NDAA. Comment: USAID involvement is not evident Response: USAID has been actively involved in various working groups implementing the Interim Final Rule and developing the Final Rule. Comment: PSC rules should be consistent with the spirit and intent of Guidelines for Relations between U.S. Armed Forces and Non-Governmental Humanitarian Agencies in Hostile or Potentially Hostile Environments Response: The purpose of publishing the IFR in the Federal Register was to obtain the comments of affected agencies, NGOs, contractors and the public. The respondent was not specific about any perceived conflicts that needed to be addressed in the PSC rule, and should work with their USAID and other agency counterparts to provide specific inputs on implementing the Final Rule. Comment: PSC rules should not apply to unarmed guard forces Response: We believe that the current language is correct. When contractors providing guard services are not armed, those aspects of the rule which are specific to armed contractors (i.e. arming procedures) are not relevant. Comment: Procedures associated with PSC rules must be adapted to contexts in which NGOs have long-standing programs or minor amounts of U.S. Government funding Response: This Rule applies only to personnel performing private security functions under a covered contract. A covered contract is defined by Section 864(a)(3) of the FY 2008 NDAA, as amended by Section 813(b) of the FY 2010 NDAA. Comment: SPOT's use for intelligence gathering and vetting is unclear Response: The Synchronized Pre-deployment and Operational Tracker (SPOT) is a Web-based database which is used to gain visibility over contracts and contractors supporting U.S. Government agencies during contingency operations. The SPOT system serves multiple purposes; it allows contractors to request and receive specific logistics support such as meals, housing, transportation, medical support while working in-country; it provides Contracting Officer Representatives and Grants Officer Representatives with information on what contractor and grantee employees are working in what locations which makes approval of invoices and inspection of work easier; it allows Contracting Officer Representatives, (printed page 49654)

(8) Each CSA will maintain a record of entity eligibility determinations made by that CSA. (9) A contractor will not use its favorable entity eligibility determination for advertising or promotional purposes. This does not prohibit the contractor from advertising employee positions that require a PCL in connection with the position. (10) A contractor or prospective contractor cannot apply for its own entity eligibility determination. A GCA or a currently cleared contractor may sponsor an entity for an entity eligibility determination at any point during the contracting or agreement life cycle at which the entity must have access to classified information to participate (including the solicitation or competition phase). (b) Reciprocity. If an entity has an appropriate, final entity eligibility determination, a CSA will not duplicate the entity eligibility determination processes performed by another CSA. If a CSA cannot acknowledge an entity eligibility determination to another CSA, the involved entity may be subject to duplicate processing in accordance with 32 CFR part 2004 . (c) Eligibility requirements. To be eligible for an initial entity eligibility determination or to maintain an existing entity eligibility determination, the entity must: (1) Need access to classified information in connection with a legitimate USG or foreign government requirement, and access must be consistent with U.S. national security interests as determined by the CSA. (2) Be organized and existing: (i) Under the laws of the United States, one of the fifty States, the District of Columbia, or an organized U.S. territory (Guam,

Commonwealth of the Northern Marianas Islands, Commonwealth of Puerto Rico, and the U.S. Virgin Islands); or (ii) Under the laws of an American Indian/Alaska Native tribal entity if: (A) The American Indian or Alaska Native tribe under whose laws the entity is chartered has been formally acknowledged by the Assistant Secretary-Indian Affairs, of the U.S. Department of the Interior. (B) The contractor is organized and continues to exist, during the period of the eligibility under a tribal statute or code, or pursuant to a resolution of an authorized tribal legislative body. (C) The contractor has submitted or will submit records such as a charter, certificate of organization, or other applicable tribal documents and statute or code provisions governing the formation and continuation of the entity, for CSA determination that the entity is tribally chartered. (3) Be located in the United States or its territorial areas. (4) Have a record of integrity and lawful conduct in its business dealings. (5) Have a SMO, FSO, and ITPSO who have and who maintain eligibility for access to classified information and are not excluded from participating in USG contracts or agreements in accordance with § 117.7(b)(1) through § 117.7(b)(3).

to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, and to preserve the confidentiality and integrity of Federal evaluation materials. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (24) System identifier and name. N05800-2, Professional Responsibility Files. (i) Exemptions. Investigatory material compiled for law enforcement purposes, may be exempt pursuant to 5 U.S.C. 552(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or which he would otherwise be eligible, as a result of maintenance of the information, the individual will be provided access to the information except to the extent that disclosure would reveal the identity of a confidential source. Any portion of this record system which falls within the provisions of 5 U.S.C. 552a(k)(2) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3), (d)(1) through (5), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I). (ii) Authority. 5 U.S.C. 552a(k)(2) (ii) Reason. The reason for asserting this exemption (k)(2) is to ensure the integrity of the litigation process. (25) System identifier and name. NM03800-1, Naval Global Maritime, Foreign, Counterterrorism and Counter Intelligence Operation Records. (i) Exemptions. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) but only to the extent that such material would reveal the identity of a confidential source. An exemption rule for this system has been promulgated in accordance with the requirements of 5 U.S.C. 553(b)(1) , (2) and (3)(c) and (e) and is published as 32 CFR part 701 . (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reason. The reason for asserting this exemption is ensure the integrity of the security and investigative material compiled for law enforcement purposes by the Department of the Navy and the Department of Defense. § 310.17 Exemptions for specific Marine Corps record systems. (a) [Reserved] (1) System identifier and name. MIN00001, Personnel and Security Eligibility and Access Information System. (i) Exemption.

The total estimated Government costs associated with this FAR rule in billions over a ten-year period are as follows: (printed page 4285) Government cost Undiscounted 2 Percent Present Value \$4.69 \$4.21 Annualized 0.47 0.47 Undiscounted Government costs (in billions) by year over the ten-year period are summarized as follows: Year 1 Year 2 Year 3 Year 4 Year 5 Year 6 Year 7 Year 8 Year 9 Year 10 0.47 \$0.47 \$0.47 \$0.47 \$0.47 \$0.47 \$0.47 \$0.47 \$0.47 \$0.47 The following is a summary from the RIA of the Government costs associated with reviewing contractor training records, investigating reports of suspected or confirmed CUI incidents, and other action associated with this FAR rule. 1. Prepare the SF XXX While an SF XXX is required to be included in every solicitation and contract that involves CUI, except those exclusively for COTS items, the Government only incurs a significant cost when the CUI is identified on the form. The contracting officer is responsible for ensuring that the SF XXX identifies the protected information involved in the system of records and includes any safeguarding and marking requirements applicable to the information in accordance with FAR 4.403. Of the 2,092,918 forms expected to specify requirements

for safeguarding CUI (see section IV.C.1.b. of this preamble), 1,573,582 are expected to be prepared by the Government (see section IV.C.1.c. of this preamble for the estimate of forms prepared by contractors and subcontractors). The total estimated annual Government cost is \$453,191,616 (1,573,582 forms * 4 hour/form * \$72/hour). 2. Review Training Records It is estimated that it will take a Government employee 30 minutes to review evidence of training submitted by the contractors (see section IV.C.1.d. of this preamble). Therefore, the estimated annual reporting cost is \$51,480 (1,430 requests * 0.5 hours/response * \$72/hour). 3. Review CUI Incident Reports It is estimated that it will take a Government employee four hours to review the CUI incident information reported by a contractor (see section IV.C.2.b. of this preamble). The estimated annual cost to the Government is \$292,900 (580 reports * 5 hours/response * \$101/hour). 4. Review Media and Data for Damage Assessment It is estimated that it will take a Government employee 10 hours to conduct a damage assessment of media and data submitted by a contractor (see section IV.C.2.c. of this preamble). The estimated annual cost to the Government is \$48,480 (48 submissions * 10 hours/response * \$101/hour). 5. Review System Security Plan It is estimated that it will take a Government employee four hours to review a system security plan submitted by a contractor (see section IV.C.1.g. of this preamble). The estimated annual cost to the Government is \$577,720 (1,430 reports * 4 hours/response * \$101/hour). 6. Conduct Validation Actions for Non-Federal Information Systems

(E) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to that individual, and record amendment procedures for this record system. (2) [Reserved] §-310.19 Defense Information Systems Agency (DISA) exemptions. (a) Section 5 U.S.C. 552a(3)(j) and (3)(k) authorize an agency head to exempt certain systems of records or parts of certain systems of records from some of the requirements of the act. This part reserves to the Director, DISA, as head of an agency, the right to create exemptions pursuant to the exemption provisions of the act. All systems of records maintained by DISA shall be exempt from the requirements of 5 U.S.C. 552a(d) pursuant to 5 U.S.C. 552a(k)(1) to the extent that the system contains any information properly classified under Executive Order 11652, Classification and Declassification of National Security Information and Material, dated March 8, 1972 (37 FR 10053, May 19, 1972) and which is required by the executive order to be kept secret in the interest of national defense or foreign policy. This exemption, which may be applicable to parts of all systems of records, is necessary because certain record systems not otherwise specifically designated for exemptions may contain isolated information which has been properly classified. (1) System identifier and name. K890.23, DISA Inspector General Investigative Tracker (DIGit). (i) Exemption. Any portion of this record system which falls within the provisions of 5 U.S.C. 552a(j)(2), (k)(2) and (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a: (c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I). (ii) Authority. 5 U.S.C. 552a(j)(2), (k)(2), and (k)(5). (iii) Reasons. To ensure the integrity of the privacy and civil liberties process. The execution requires that information be provided in a free and open manner without fear of retribution or harassment in order to facilitate a just, thorough, and timely resolution of the complaint or inquiry. Disclosures from this system can enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying, or fabricating evidence or documents. In addition, disclosures can subject sources and witnesses to harassment or intimidation which may cause individuals not to seek redress for wrongs through privacy and civil liberties channels for fear of retribution or harassment. (2) [Reserved] §-310.20 Defense Intelligence Agency (DIA) exemptions.

(7) A DA activity may refer a Privacy Act request for records that originated in an agency outside of DOD, or that is based on information obtained from an agency outside the DOD, to that agency for direct response to the requester, only if that agency is subject to the Privacy Act. Otherwise, the DA activity must respond to the request. (8) DA activities will not honor any Privacy Act requests for investigative, intelligence, or any other type of records that are on loan to the Department of Defense for a specific purpose, if the records are restricted from further release in writing. Such requests will be referred to the agency that provided the records. (9) A DA activity will notify requesters seeking National Security Council (NSC) or White House documents that they should write directly to the NSC or White House for such documents. DA documents in which the NSC or White House

have a concurrent reviewing interest will be forwarded to the Department of Defense, Office of Freedom of Information and Security Review, which will coordinate with the NSC or White House, and return the documents to the originating DA activity after NSC or White House review. NSC or White House documents discovered in DA activity files which are responsive to a Privacy Act request will be forwarded to DOD for coordination and return with a release determination. (10) To the extent referrals are consistent with the policies expressed above; referrals between offices of the same DA activity are authorized. (l) Reproduction fees. (1) Use fees only to recoup direct reproduction costs associated with granting access. (2) DA activities may use discretion in their decision to charge for the first copy of records provided to an individual to whom the records pertain. Thereafter, fees will be computed pursuant to the fee schedule set forth in AR 25-55, including the fee waiver provisions. (3) Checks or money orders for fees should be made payable to the Treasurer of the United States and will be deposited in the miscellaneous receipts of the treasury account maintained at the activity's finance office. (4) Reproduction costs shall only include the direct costs of reproduction and shall not include costs of: (i) Time or effort devoted to searching for or reviewing the records by personnel; (ii) Fees not associated with the actual cost of reproduction; (iii) Producing a copy when it must be provided to the individual without cost under another regulation, directive, or law; (iv) Normal postage; (v) Transportation of records or personnel; or (vi) Producing a copy when the individual has requested only to review the records and has not requested a copy, and the only means of allowing review is to make a copy (e.g., the records are stored in a computer and a copy must be printed to provide individual access, or the activity does not wish to surrender temporarily the original records for the individual to review). (m) Privacy Act case files.

This document is for security managers, engineers, administrators, and others who are responsible for planning, acquiring, testing, implementing, and maintaining SSH solutions. Portions of the document may be of interest to executives and SSH users. - - Mapping all trust relationships that result from deployed identity and authorized keys and requiring review and approval from their owners (including description of the purpose of the key or other justification for the existence of the key). Trust relationships created by public key authentication must be reviewed and evaluated based on the potential for chains of trust relationships coming in and out of systems to be used to pivot. Source and command restriction information should be included to enable evaluation of proper access controls and restrictions. Any keys for which such approval is not deemed appropriate (such keys may be backdoors and may have been left behind by attackers) should be removed. Ideally, trust relationship information can be imported into existing privilege access management systems for review through standard processes.

, as providing access to records of a civil or administrative investigation, and the right to contest the contents of those records and force changes to be made to the information contained therein, would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would: Provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal wrongdoing or mislead the course of the investigation; and result in the secreting (printed page 14777) of or other disposition of assets that would make them difficult or impossible to reach to satisfy any Government claim arising from the investigation or proceeding. (C) From 5 U.S.C. 552a(e)(1) , as it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From 5 U.S.C. 552a(e)(4)(G) and (H) , as this system of records is compiled for law enforcement purposes and is exempt from the access provisions of 5 U.S.C. 552a(d) and (f) . (E) From 5 U.S.C. 552a(e)(4)(I) , because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. DLA, nevertheless, will continue to publish such a notice in broad generic terms as is its current practice. (5) System identifier and name. S500.60 (Specific exemption), Defense Logistics Agency Enterprise Hotline Program Records. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . If an individual, however, is denied any right, privilege, or benefit for

which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information, except to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(5)(i)(A): When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to

. The Department believes this is unlikely to occur more frequently than once per year and that the time to do so would be minimal because the proposed requirement does not specify the means or scope of such notification. The Department estimates that business associates would need an average of 30 minutes (with 15 minutes as a low estimate and 45 minutes as a high estimate) to report to other regulated entities, as applicable, when their contingency plan is activated at the wage rate of an information security analyst for a total annual cost of \$59,970,000 [= 1,000,000 business associates × 0.5 hours × \$119.94], with a low estimated total of \$29,985,000 [= 1,000,000 business associates × 0.25 hours × \$119.94] and high estimated total of \$89,955,000 [= 1,000,000 business associates × 0.75 hours × \$119.94]. j. Revised Health Plan Documents The Department estimates that health care insurers and third-party administrators would need to revise health plan documents to reflect that health plan sponsors that receive ePHI (that is not limited to summary health information or disenrollment information) are protecting ePHI with the administrative, physical, and technical safeguards detailed in the Security Rule, as proposed. These 6,162 entities collectively would be responsible for updating approximately 742,411 health plan documents at the wage rate of a compensation and benefits manager. The Department's estimate assumes that on average each plan document requires 30 minutes to update for a total estimated cost of \$53,876,766 [742,411 × 0.5 hours × \$145.14]. The Department has attributed these costs solely to health plans and not health plan sponsors because the health plan is the regulated entity. k. Estimated Costs for Developing New or Modified Policies and Procedures

3.3.4 Moderate Baseline Security Control Item Narratives ... 3.3.4). 3.3.4) | (3) High Control Items (Section 3.

FDA estimates the number of Mexican carriers that are subject to DOT regulations from a study conducted for DOT by Economic Data Resources under the auspices of the International Association of Chiefs of Police (Ref. 23). Using 1999 U.S. Customs and Border Protection data on the use of annual decals and per-trip payments by commercial vehicles at Southwest border crossings, that study estimated the total number of vehicles that cross the Southwest border to be approximately 76,177. Furthermore, using 1998 data on Mexican interstate commercial vehicle registrations, the DOT study estimated the number of commercial carriers of Mexican origin that use the Southwest border crossings to be approximately 63,000, or approximately 83 percent of the total. If one half of the total number of these trucks carry food items, then approximately 31,500 carriers of Mexican origin are subject to this final rule and would not be counted in the CBP or NES data. In order to estimate the number of commercial carriers of Canadian origin that would be covered by this final rule, from the DOT study we obtain an estimate of approximately 79,643 carriers that purchase annual decals at the Northern border. We assume the same ratio of the total number of trucks that purchase annual decals for Southwest border crossings as that for northern border crossings (42 percent) and estimate the total number of trucks that cross the northern border to be approximately 191,167. Furthermore, we assume the percentage of these carriers that are of Canadian origin is the same as that used to estimate Southwest border crossings by Mexican carriers (83 percent). This assumption yields a total of 158,099 carriers of Canadian origin that are subject to DOT regulations. If one half of the total number of these trucks carry food items, then approximately 79,050 carriers of Canadian origin are subject to this final rule and would not be counted in the CBP or NES data. The number of transport facilities is revised upward by 110,550 (i.e., 79,050 plus 31,500) to account for the number of foreign based transporters that are subject to the final rule and not counted in the NES or CBP data. (Comment 183) One comment states that direct selling businesses are clearly not accounted for because there are millions of such entities involved on either a full or part-time basis, while the combined estimate of domestic retailers and wholesalers used in the analysis is only slightly more than 300,000. Furthermore, the comment states that the burden on these retailers would be higher than for other retailers. (printed page 71632)

ent users, such as giving some users read-only access to the administrative interface of a guest OS, other users control over particular guest OSs, and yet other users complete administrative control. Most hypervisor software currently only uses passwords for access control; this may be too weak for some organizations' security policies and may require the use of compensating controls, such as a separate authentication system used for restricting access to the host on which the virtualization management system is installed.

been performed prior to granting access? Do the organization's systems have the capacity to set access controls? Are there additional access control requirements for users who would be accessing privileged functions? Have organizational personnel been explicitly authorized to approve user requests to access ePHI and/or systems with ePHI? The Department proposes three additional implementation specifications for authentication management, maintenance, and network segmentation. These specifications clarify the Department's expectations for compliance and are consistent with NIST guidance. We believe that the proposed additions would assist regulated entities in their efforts to prevent or mitigate attacks by malicious internal and external actors. For the implementation specification on authentication management at proposed 45 CFR 164.308(a)(10)(ii)(C), we propose to require a regulated entity to establish and implement written policies and procedures for verifying the identities of users and technology assets before accessing the regulated entity's relevant electronic information systems, including written policies and procedures for implementing MFA technical controls. [579] The proposed implementation specification for network segmentation at proposed 45 CFR 164.308(a)(10)(ii)(E) would require a regulated entity to establish and implement written policies and procedures that ensure that its relevant electronic information systems are segmented to limit access to ePHI to authorized workstations. Finally, to address the Department's general concerns regarding the ongoing failure of many regulated entities to regularly review and revise their policies and procedures, the proposed implementation specification for maintenance at proposed 45 CFR (printed page 952) 164.308(a)(10)(ii)(F) would require a regulated entity to review the written policies and procedures required by this standard at least once every 12 months and to modify them as reasonable and appropriate. m. Section 164.308(a)(11)(i)·Standard: Security Awareness Training A covered entity's workforce is its frontline not only in patient care and patient service, but also in safeguarding the privacy and security of PHI. [580] The health care sector's risk landscape continues to grow with the increasing number of interconnected, smart devices of all types, the increased use of interconnected medical record and billing systems, and the increased use of applications and cloud computing. This standard reflects the fact that training on data security for workforce members is essential for protecting an organization against cyberattacks.

CM.L2-3.4.7 · Nonessential Functionality CMMC Assessment Guide · Level 2 | Version 2.13 105
CM.L2-3.4.7 · NONESSENTIAL FUNCTIONALITY Restrict, disable, or prevent the use of nonessential programs, functions, ports, protocols, and services. ASSESSMENT OBJECTIVES [NIST SP 800-171A]92
Determine if: [a] essential programs are defined; [b] the use of nonessential programs is defined; [c] the use of nonessential programs is restricted, disabled, or prevented as defined; [d] essential functions are defined; [e] the use of nonessential functions is defined; [f] the use of nonessential functions is restricted, disabled, or prevented as defined; [g] essential ports are defined; [h] the use of nonessential ports is defined; [i] the use of nonessential ports is restricted, disabled, or prevented as defined; [j] essential protocols are defined; [k] the use of nonessential protocols is defined; [l] the use of nonessential protocols is restricted, disabled, or prevented as defined; [m] essential services are defined; [n] the use of nonessential services is defined; and [o] the use of nonessential services is restricted, disabled, or prevented as defined. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]92 Examine [SELECT FROM: Configuration management policy; procedures addressing least functionality in the system; configuration management plan; system security plan; system design documentation; security configuration checklists; system configuration settings and associated documentation; specifications for preventing software program execution; documented reviews of programs, functions, ports, protocols, and/or services; change control records; system audit logs and records; other relevant documents or records]. 92 NIST SP 800-171A, p. 29.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) has the broad mission of supporting U.S. industry, government, and academia by promoting U.S. innovation and industrial competitiveness through advancement of information technology measurement science, standards, and technology in ways that enhance economic security and improve our quality of

life. ITL researchers have developed detailed protocols and operational standards that improve safety of their operation, and established assessment criteria and test data sets for validation of industrial products. ITL formulates metrics, tests, and tools for a wide range of subjects such as information complexity and comprehension, high confidence software, space-time coordinated mobile and wireless computing, as well as, issues of information quality, integrity, and usability. Under the Federal Information Security Management Act, ITL is directed to develop cyber security standards, guidelines, and associated methods and techniques. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of non national-securityrelated information in federal information systems. This Interagency Report provides an overview of the NIST Program Review for Information Security Management Assistance (PRISMA) methodology. NIST would like to thank the many people who assisted with the development of this handbook. NIST management officials who supported this effort include: Joan Hash, William C. Barker, Elizabeth Chew, and Matthew Scholl. The structure of a PRISMA Review is based upon the Software Engineering Institute's (SEI) former Capability Maturity Model (CMM), where an organization's developmental advancement is measured by one of five maturity levels.

3.5.1 | Group Attribute Use Metadata... 3.5.1 Group Attribute Use Metadata In the course of managing attributes, metadata is applied to subjects and objects as extended attribute information useful for enforcing fine-grained access control policies that incorporate information about the attributes and manage the volumes of data required for enterprise attribute management.

tion architectures are information system developers and integrators, information system owners, information system/security engineers, and end users. Vulnerability identification occurs at all tiers. Vulnerabilities related to organizational governance (e.g., inconsistent decisions about the relative priorities of mission/business processes, selection of incompatible implementations of security controls) as well as vulnerabilities related to external dependencies (e.g., electrical power, supply chain, telecommunications), are most effectively identified at Tier 1. However, most vulnerability identification occurs at Tiers 2 and 3. At Tier 2, process and architecture-related vulnerabilities (e.g., exploitable weaknesses or deficiencies in mission/business processes, enterprise /information security architectures including embedded information security architectures) are more likely to be identified. At Tier 3, information system vulnerabilities are the primary focus. These vulnerabilities are commonly found in the hardware, software, and firmware components of information systems or in the environments in which the systems operate. Other areas of potential vulnerabilities include vulnerabilities associated with the definition, application/implementation, and monitoring of processes, procedures and services related to management, operational, and technical aspects of information security. Vulnerabilities associated with architectural design and mission/business processes can have a greater impact on the ability of organizations to successfully carry out missions and business functions due to the potential impact across multiple information systems and mission environments. The refined vulnerability assessments conducted at Tiers 2 and 3 are shared with organizational personnel responsible for assessing risks more strategically.

The proposed rule introduces a new standard form (SF) to support uniformity in Governmentwide implementation of these policies. It identifies roles and responsibilities for agencies and contractors when controlled unclassified information (CUI) is located on Federal information systems within a Federal facility or resides on or transits through contractor information systems or within contractor facilities, and it adds two new clauses and a provision to enable contractor reporting and compliance responsibilities in Federal solicitations and contracts. The proposed rule is intended to provide for the following: (1) SF XXX, Controlled Unclassified Information (CUI) Requirements, was developed to promote consistency, assist Federal agencies and contractors in the identification of CUI in agency requirements, and uniformly define all associated handling requirements in accordance with 32 CFR part 2002 . The SF XXX will be included in solicitations and contracts that may result in the handling of CUI that will ultimately become performance requirements during contract performance. (2) FAR 2.101 definitions for ·contractor-attributional information,· ·controlled unclassified information (CUI),· ·CUI incident,· and ·CUI Registry· are added to provide clarification as these terms are new to the FAR. The definition of ·information system· is moved from FAR subpart 4.19 to 2.101. The term ·Federally-controlled information system· is updated to ·Federal information system.· (3) FAR 3.104-4 is amended to clarify that certain information must be marked by the contractor before submitting it to the Government (contractor bid

or proposal information, contractor-attributional information, contractor proprietary business information, and source selection information). Contracting officers should consult with the contractor if they are unsure whether information provided by the contractor falls into one of these categories. Contracting officers who are unsure how to handle such information, including whether it is CUI, should consult with agency officials as necessary. (4) FAR subpart 4.4: The subpart heading is revised to read 'Safeguarding Information and Information Systems' since the information referred to in subpart 4.4 is not limited to classified information and now includes CUI. Section 4.401 is amended to add a definition for 'information' which was moved and revised from the definition currently at FAR 4.1901. At FAR 4.403 and 4.404, the current content is moved to FAR 4.402.

The OSA will achieve CMMC Level 2 Final Self-Assessment compliance for the information system(s) within the CMMC Assessment Scope upon implementation of all security requirements and close out of the POA&M, as applicable. (iv) CMMC status revocation. If the CMMC PMO determines that the provisions of Level 1 or Level 2 of this rule have not been achieved or maintained, as addressed in § 170.6, a revocation of the validity status of the CMMC Level 2 Self-Assessment may occur. At that time, standard contractual remedies will apply and the OSA will be ineligible for additional awards with CMMC Level 2 Self-Assessment or higher requirements for the information system within the CMMC Assessment Scope until such time as a valid CMMC Level 2 Self-Assessment is achieved. (2) Affirmation. Affirmations are required at the time of each assessment, and annually thereafter, for all CMMC Level 2 Self-Assessments. Affirmation procedures are provided in § 170.22. (b) Contract eligibility. In order to be awarded a contract from DoD with a CMMC Level 2 Self-Assessment requirement, the following two requirements must be met: (1) OSAs must achieve, as specified in paragraph (a)(1) of this section, either CMMC Level 2 Conditional Self-Assessment or CMMC Level 2 Final Self-Assessment. (2) OSAs must submit an affirmation of compliance into SPRS, as specified in § 170.16(a)(2). (c) Procedures. (1) Self-Assessment. The OSA must perform a CMMC Level 2 Self-Assessment in accordance with NIST SP 800-171A (incorporated by reference, see § 170.2) and the CMMC Level 2 scoping requirements set forth in § 170.19(a) and (c) for the information systems within the CMMC Assessment Scope. The assessment must be scored in accordance with the CMMC Scoring Methodology described in § 170.24. If a POA&M exists, a POA&M closeout assessment must be performed by the OSA when all remaining requirements have been remediated. The POA&M closeout assessment must be performed within the 180-day closeout period. Additional guidance can be found in the guidance document listed in paragraph (c) of appendix A to this part. (2) Self-Assessment of Cloud Service Provider. An OSA may use a Federal Risk and Authorization Management Program (FedRAMP) Moderate (or higher) cloud environment to process, store, or transmit CUI in execution of a contract or subcontract with a requirement for CMMC Level 2 under the following circumstances: (i) The Cloud Service Provider's (CSP) product or service offering is FedRAMP Authorized at the FedRAMP Moderate (or higher) baseline in accordance with the FedRAMP Marketplace; or

, the 110 Level 2 requirements from NIST SP 800-171 R2 (incorporated by reference, see § 170.2), and the 24 Level 3 requirements selected from NIST SP 800-172 Feb2021 (incorporated by reference, see § 170.2). CMMC Status is the result of meeting or exceeding the minimum required score for the corresponding assessment. The CMMC Status of an OSA information system is officially stored in SPRS and additionally presented on a Certificate of CMMC Status, if the assessment was conducted by a C3PAO or DCMA DIBCAC. The potential CMMC Statuses are outlined in the paragraphs that follow. (CMMC-custom term) (i) Final Level 1 (Self) is defined in § 170.15(a)(1) and (c)(1). (CMMC-custom term) (ii) Conditional Level 2 (Self) is defined in § 170.16(a)(1)(ii). (CMMC-custom term) (iii) Final Level 2 (Self) is defined in § 170.16(a)(1)(iii). (CMMC-custom term) (iv) Conditional Level 2 (C3PAO) is defined in § 170.17(a)(1)(ii). (CMMC-custom term) (v) Final Level 2 (C3PAO) is defined in § 170.17(a)(1)(iii). (CMMC-custom term) (vi) Conditional Level 3 (DIBCAC) is defined in § 170.18(a)(1)(ii). (CMMC-custom term) (vii) Final Level 3 (DIBCAC) is defined in § 170.18(a)(1)(iii). (CMMC-custom term) CMMC Status Date means the date that the CMMC Status results are submitted to SPRS or the CMMC instantiation of eMASS, as appropriate. The date of the Conditional CMMC Status will remain as the CMMC Status Date after a successful POA&M closeout. A new date is not set for a Final that follows a Conditional. (CMMC-custom term) CMMC Third-Party Assessment Organization (C3PAO) means an organization that has been authorized or accredited by the Accreditation Body to conduct Level 2 certification assessments and has the roles and responsibilities identified in § 170.9. (CMMC-custom term) Contractor is defined in 48 CFR 3.502-1. Contractor Risk Managed Assets are defined in table 3 to § 170.19(c)(1). (CMMC-custom term) Controlled Unclassified Information (CUI) is defined in 32 CFR 2002.4(h). Controlled

Unclassified Information (CUI) Assets means assets that can process, store, or transmit CUI. (CMMC-custom term) DCMA DIBCAC High Assessment means an assessment that is conducted by Government personnel in accordance with NIST SP 800-171A Jun2018 and leveraging specific guidance in the DoD Assessment Methodology that: (i) Consists of: (A) A review of a contractor's Basic Assessment; (B) A thorough document review; (C) Verification, examination, and demonstration of a contractor's system security plan to validate that NIST SP 800-171 R2 security requirements have been implemented as described in the contractor's system security plan; and (D) Discussions with the contractor to obtain additional information or clarification, as needed; and (ii) Results in a confidence level of 'High' in the resulting score. (Source: 48 CFR 252.204-7020). Defense Industrial Base (DIB) is defined in 32 CFR 236.2 . DoD Assessment Methodology (DoDAM)

For ubiquitous access to these applications from multiple remote locations using different types of devices, it is necessary to build the concept of zero trust [1] into this application environment. Zero trust assumes that there is no implicit trust granted to assets or user accounts based solely on their physical or network location (i.e., local area networks versus the internet) or based on asset ownership (enterprise or personally owned) [1]. Zero trust focuses on protecting resources (e.g., assets, services, workflows, and network accounts) rather than network segments since the network location is no longer seen as the prime component to the security posture of the resource. Furthermore, the loosely coupled nature of the components (i.e., microservices) of these cloud-native applications facilitates independent design, development, and agile deployment (e.g., Continuous Integration/ Continuous Delivery or Deployment (CI/CD) [2]) of the constituent microservices, enabling paradigms such as DevSecOps [3] (representing Development, Security and Operations) to be used.

Identification and Authentication 20 - Precision in Terminology - Identification and Authentication - Access Control - Availability & Fault Tolerance - Policy Neutral Criteria - TCB & Reference Monitor Focus - Integrity - Open-Ended Criteria - Issues from the attendees ## Identification and Authentication

Rather than abandon the CMMC ecosystem model entirely, some commenters recommended only that DoD revise the CMMC Accreditation Body's roles and responsibilities. Three recommended the DoD eliminate the CMMC AB and take on its responsibilities; of these, one further suggested the DoD publish detailed Security Technical Implementation Guides describing how to implement the applicable NIST requirements. One commenter questioned the reasons for creating a CMMC AB rather than accepting another existing accreditation body or multiple accreditation bodies. One comment expressed doubt in the ability of the ecosystem to scale sufficiently to meet the demand for C3PAO assessments and assessor training. Multiple comments called for organizations other than the current CMMC AB to run the CMMC ecosystem such as a CMMC Advisory Council or a Civilian Cybersecurity Corps comprised of government and private sector staff. One such comment requested that, unlike the current CMMC AB, the proposed body would be funded and managed by the government. Two commenters recommended the DoD consider accepting other types of conformance assessment such as ISO/IEC 27001:2022(E) and Health Information Trust Alliance (HITRUST) certification. One noted this would require guidance to describe how to address the gaps between standards those assessments are aligned to and those that CMMC are aligned to (e.g., NIST SP 800-171 R2 for CMMC Level 2). This commenter further suggested that DoD accept alternate industry certifications in lieu of the training requirements identified for CMMC Assessors. One commenter suggested the DoD accept FedRAMP authorization to meet CMMC assessment requirements. Response:

Finally, because the HITECH Act made business associates directly liable for compliance with the Security Rule, the 2013 Omnibus Rule modified the Security Rule to clarify that a covered entity is not required to obtain satisfactory assurance from a business associate that is a subcontractor that the subcontractor will appropriately safeguard its ePHI. Rather, the business (printed page 906) associate of the covered entity must obtain the required satisfactory assurances from the subcontractor to protect the security of ePHI. [107] III. Justification for This Proposed Rulemaking HIPAA and the HIPAA Rules promote access to high-quality and effective health care by establishing standards for the security of ePHI. The standards, when implemented appropriately by regulated entities, protect the confidentiality, integrity, and availability of individuals' health information. Such protections promote the electronic transmission of PHI through a national health information system. To ensure access to high-quality health care services, regulated entities must assure their customers (e.g., individuals, health care providers, and health plans) of the

security of the sensitive and confidential health information the regulated entities electronically create, receive, maintain, or transmit. As discussed above, the Security Rule carefully balances the benefits of safeguarding against security risks with the burdens of implementing protective measures by permitting regulated entities to consider several factors, including costs and available technology for preventing and mitigating security risks, [108] when determining which security measures are reasonable and appropriate for protecting the security of individuals' ePHI. [109] For example, the Security Rule requires that a regulated entity implement policies and procedures to limit physical access to its electronic information systems and the facilities in which they are housed, while ensuring that users who are authorized to access such information systems and facilities are permitted to do so. [110] The implementation specifications associated with this standard only address the need for operationalized policies and procedures related to specific aspects of physical security. [111] They do not dictate the specifics of such policies and procedures because we recognize that the nature of the physical safeguards should depend on the type of regulated entity, its size, its level of access to ePHI, and a number of other factors. Since the Security Rule's promulgation in 2003, the environment in which health care is provided and in which regulated entities operate has changed significantly, including transformative changes in how regulated entities create, receive, maintain, and transmit ePHI. For example, as of 2021, almost 80 percent of physician offices and 96 percent of hospitals had adopted certified EHRs. [112]

- (1) Data Integrity, - (2) Data Confidentiality, - (3) Data Origination Authentication, and - (4) Access Control. The SP4E Entity is composed of two types of submodules: the SP4 Machine and the Timer Facility. The SP4 Machine submodule encapsulates and decapsulates Transport Protocol data units within a security envelope for protection. It can provide the full functionality of SP4, although not fully utilized by the SP4E Entity. The SP4 Machine submodule uses the interface to the Key Manager module to request, replace, return, and verify traffic key assignment. Assigned keys are used, in turn, through the interface to the Cryptographic Facility to encipher/decipher information and compute integrity check values. The Timer Facility submodule provides the SP4 Machine with a mechanism for determining protracted delays with the Key Manager. The two submodules communicate with each other through an internal interaction point. Like the Access Control Facility, a group of function and procedure definitions makes up the interface to the SMIB. Collectively they provide the capability to create new objects, to manipulate existing objects that populate the SMIB, to enter, access, or modify information stored as attributes of those objects, and to destroy objects no longer needed. The interface operates at the object level. It is used exclusively by the Key Manager and its submodules, who are relied upon to maintain the integrity of the SMIB.

(ii) USG personnel assigned to or visiting a contractor facility and engaged in oversight of an acquisition program (printed page 83345) will retain control of their work product. Classified work products of USG employees will be handled in accordance with this rule. Contractor procedures will not require USG employees to relinquish control of their work products, whether classified or not, to a contractor. (iii) Contractor employees at USG installations will follow the security requirements of the host. This does not relieve the contractor from security oversight of their employees who are long-term visitors at USG installations. (b) Classified meetings. This paragraph applies to a conference, seminar, symposium, exhibit, convention, training course, or other such gathering during which classified information is disclosed, hereafter called a meeting. Disclosure of classified information to large diverse audiences such as conferences increases security risks. Classified disclosure at such meetings may occur when it serves a government purpose and adequate security measures have been provided in advance. (1) Meeting conducted by a cleared contractor. If conducted by a cleared contractor, the meeting is authorized by a USG agency that has agreed to assume security jurisdiction. The USG agency: (i) Must approve security arrangements, announcements, attendees, and the location of the meeting. (ii) May delegate certain responsibilities to a cleared contractor for the security arrangements and other actions necessary for the meeting under the general supervision of the USG agency. (2) Request for authorization. Contractors desiring to conduct meetings that require sponsorship will submit their requests to the USG agency that has principal interest in the subject of each meeting. Requests for authorization will include: (i) An explanation of the USG purpose to be served by disclosing classified information at the meeting and why the use of conventional channels for release of the classified information will not advance those interests. (ii) The subject of the meeting and scope of classified topics, to include the classification level, to be disclosed at the meeting. (iii) The expected dates and location of the meeting. (iv) The general content of the proposed announcement or invitation to be sent to prospective attendees or participants. (v) The identity of any other

non-government organization involved and a full description of the type of support it will provide. (vi) A list of any foreign representatives (including their nationality, name, organizational affiliation) whose attendance at the meeting is proposed. (vii) A description of the security arrangements necessary for the meeting to comply with the requirements of this rule. (3) Locations of meetings.

DoD, GSA, and NASA are proposing to amend the FAR to update and clarify the requirements for using the DD Form 254, Contract Security Classification Specification. The Government uses the DD Form 254 to convey security requirements to contractors when contract performance requires access to classified information. Prime contractors also use the DD Form 254 to convey security requirements to subcontractors that require access to classified information to perform on a subcontract. Subcontractors may also use the DD Form 254 if access to classified information is required to convey security requirements to additional subcontractors. The Defense Security Service has oversight responsibilities for contractors and subcontractors requiring access to classified information under contracts awarded by agencies covered by the National Industrial Security Program, i.e., DoD components, and nondefense agencies that have industrial security services agreements with DoD. The National Industrial Security Program was established under Executive Order (E.O.) 12829 as a single, integrated program across the Executive Branch designed to safeguard classified information released to contractors. As one of five National Industrial Security Program cognizant security agencies, DoD is responsible for providing industrial security oversight services to DoD and those nondefense agencies that have industrial security services agreements with DoD. The National Industrial Security Program Contracts Classification System is a module within the Procurement Integrated Enterprise Environment (PIEE), (formerly the Wide Area Workflow application). The module provides a centralized repository for classified contract security requirements and automates DD Form 254 processes and workflows.

II. Discussion and Analysis This rule proposes to amend the FAR to provide procedures for use of the DD Form 254 and the requirement to use the PIEE, to:

- Streamline the submission process for the existing DD Form 254 and enable businesses to submit an electronic form once, instead of repeated paper submissions;
- Require use of the DD Form 254 by nondefense agencies that have industrial security services agreements with DoD, and DoD components, to specify the security classification for a contract involving access to information classified as Confidential, Secret, or Top Secret;
- Require agency preparation of the DD Form 254 using the National Industrial Security Program Contracts Classification System module of the PIEE unless a nondefense agency has an existing DD Form 254 information system;
- Clarify that (printed page 33202) Each contractor and subcontractor location of performance listed on a DD Form 254 is required to have a unique CAGE code; and
- Registration in the System for Award Management is not required for contractor and subcontractor performance locations solely for the purposes of the DD Form 254.

Federal Information System Controls Audit Manual | U.S. Government Accountability Office | gigabyte | GR | graceful restart | |-----|-----| | GRE | Generic Routing Encapsulation | | GRS | General Records Schedule | | GS1 | Global Standards One | | GSA | U.S. General Services Administration | | GSM | Global System for Mobile Communications | | GTC | Generic Token Card | | GTEK | group traffic encryption key | | GTK | group temporal key | | gTLD | generic top-level domain | | GTSM | Generalized TTL Security Mechanism | | GUI | graphical user interface | | H | | HA | high availability | | HA | home agent | | HAG | high assurance guard | | HCI | host controller interface | | HERF | hazards of electromagnetic radiation to fuel | | HERO | hazards of electromagnetic radiation to ordnance | | HERP | hazards of electromagnetic radiation to personnel | | HF | high frequency | | HFS | Hierarchical File System | | HHS | U.S.

A few comments asked about the assumptions used to estimate numbers of assessments by category and stated the labor rates for ESPs and C3PAOs were too low, and costs associated with small entities were incorrect. Two comments also suggested the number of hours estimated for self-assessment are too low, and three questioned the accuracy of small and medium sized business labor rates and asserted that the assessment costs for small businesses were not sustainable. One comment suggested that cost data in existing/past contracts should be used as a part of CMMC cost analysis and Section H costs should apply to the current CMMC cost estimate. One comment claimed it is cost prohibitive for individuals to obtain a CCP or CCA certification, which will hamper the CMMC Program's scalability. One comment requested the government elaborate on how the estimated 417.83 hours per response was derived for table 39, C3PAOs Level 1 Certification and Assessment, in section §.170.17(a). Another comment asserted that assessments conducted by Defense Technical Risk

Assessment Methodology (DTRAM) assessment teams require more manhours than are anticipated for CMMC certification assessments. One comment stated that while DoD included an estimate for annual senior official affirmations in the Regulatory Impact Analysis, it assumed a minimal number of hours will be required to complete this task which may not be adequate to complete a full compliance review. One comment stated the DoD self-assessment resource allocations for an ESP for both CMMC Level 1 and Level 2 are estimated 125% to 175% too low based on the belief that a self-assessment should have more rigor than a gap analysis. Specifically, the commenter posed questions on what inputs from potential OSAs were used and identifying the rigor a Certifying Official would require for attestation. Recommendations include that the DoD clearly state its assumptions regarding self-assessment rigor, have OSA legal counsel review assumptions and cost factors, and identify a representative cross-section of stakeholders to determine appropriate rigor assumptions for company's ESPs and new to CMMC self-assessments. One comment stated that the DoD's assumptions for the level of effort expressed as Director and staff IT specialist hours are too low. Although there are continuous monitoring requirements of NIST 800-171 R2, those requirements do not invoke the level of effort necessary for an executive to make an attestation corresponding to the level of personal risk and corporate liability incurred under the False Claims Act. The comment asserted that DoD's assumptions failed to account for an SMB to acquire and manage technical tools or manage the reaffirmation or an enterprise change management effort. (printed page 83154)

Addressing the harmonization between the DoD, contractors, and subcontractors is beyond the scope of this rule. These are functions of the DIB Sector Coordinating Council and the DIB Government Coordinating Council. Additionally, non-DoD programs are outside the control and scope of the 32 CFR part 170 CMMC Program rule. The DoD encourages prime contractors to work with its subcontractors to flow down CUI with the required security and the least burden. DoD is aware organizations may receive multiple contracts that may require different CMMC levels based upon programmatic data security needs. It is beyond the scope of this rule to (printed page 83156) dictate how OSAs manage varying contract requirements. Contractors that have achieved a CMMC Level 2 or Level 3 certification automatically meet a stated requirement of a lower CMMC level if the same system/assessment scope will be used in performance of the contract. 30. Alternatives a. Alternate Programs Comment: Many comment submissions included lengthy proposals for alternatives to the CMMC program purported to alleviate specific concerns with aspects of CMMC program requirements. In some cases, the concerns were based on a misreading of the rule's content. The DoD has addressed some valid concerns through rule revisions that differ from the recommendations. One commenter suggested eliminating compliance assessments in favor of establishing a DoD office to conduct penetration testing of each DIB company's network every two years. Other commenters also recommended the DoD establish a secure portal and share CUI with contractors only through that portal, as a way for the DIB to avoid the cost of securing their information systems. One commenter suggested the DoD monitor use of waivers and utilize this secure portal approach when CMMC waivers apply. Similar recommendations included sharing CUI only through password encrypted files or requiring contractors to store CUI in restricted access folders. In similar suggestions, several commenters thought the DoD should provide its contractors with training, GFE and other tools necessary to secure the contractor owned information systems being used to process or store CUI. One such commenter stated that the Government should appropriate funding for secure solutions rather than phasing in compliance assessments. One commenter suggested the DoD consider industry's application of alternate security mechanisms in lieu of CMMC Levels 2 and 3. Another recommended the DoD stand up a voluntary DIB Cyber Protection Program to improve real-time monitoring of the DIB, improve cybersecurity for firms that cannot afford the needed professional staff, and offer data and legal protections to DIB firms. Another such commenter suggested that DoD fund securing the DIB through contract incentives.

(A) Information specifically authorized to be classified under E.O. 12958 , as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6) , if the disclosure would compromise the objectivity or fairness of the test or examination process. (D) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7) , but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (E) Portions of

this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(1), (e)(4)(G) through (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(1), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Granting individuals access to portions of this system of records could result in the disclosure of classified material, or the identification of sources who provided information to the government under an express or implied promise of confidentiality. Material will be screened to permit access to unclassified material and to information that does not disclose the identity of a confidential source. (4) System identifier and name. N01640-1, Individual Correctional Records. (i) Exemption. (A) Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principle function any activity pertaining to the enforcement of criminal laws. (printed page 14765) (B) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (c)(4), (d), (e)(2), (e)(3), (e)(4)(G) through (I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2). (iii) Reason.

Foreign visitors will not be given custody of classified material except when they are acting as official couriers of the government and the CSA authorizes the transfer. (iii) Visitor records. The contractor will maintain a record of foreign visitors for one year when the visit involves access to classified information. (iv) Temporary approval of safeguarding. (A) Classified U.S. and foreign government material at a U.S. contractor location is to remain under U.S. contractor custody and control and is subject to self-inspection and CSA security reviews. (B) This does not preclude the contractor from furnishing a foreign visitor with a security container for the temporary storage of classified material, consistent with the purpose of the visit or assignment, provided the CSA approves and responsibility for the container and its contents remains with the U.S. contractor. (1) The CSA may approve exceptions to this policy on a case-by-case basis for the storage of foreign government classified information furnished to the visitor by the visitor's government through government channels. (2) The CSA must approve such exceptions in advance in writing with (printed page 83354) agreement from the visitor's government. The agreed procedures will be included in the contractor's TCP, will require the foreign nationals to provide receipts for the material, and will include an arrangement for the CSA to ensure compliance, including provisions for the CSA to inspect and inventory the material. (v) TCP. A TCP is required to control access by foreign nationals assigned to, or employed by, cleared contractor facilities, and when foreign nationals visit cleared contractor facilities on a long-term or extended basis, unless the CSA determines that procedures already in place at the contractor's facility are adequate. The TCP will contain procedures to control access for all export-controlled information. A sample TCP may be obtained from the CSA. (f) Contractor operations abroad. (1) Access by contractor employees assigned outside the United States. (i) Contractor employees assigned outside the United States, its possessions, or territories may have access to classified information in connection with performance on a specified U.S., NATO, or foreign government classified contract. (ii) The assignment of an employee who is a non-U.S. citizen outside the United States on programs that will involve access to classified information is prohibited. (2) Storage, custody, and control of classified information abroad by contractor employees. (i) The USG is responsible for the storage, custody, and control of classified information required by a U.S. contractor employee abroad. Therefore, the storage of classified information by contractor employees at any location abroad that is not under USG control is prohibited. The storage may be at a U.S. military facility, an American Embassy or consulate, or other location occupied by a USG organization.

Some types of credentials are very easy to transfer to another individual. For instance, PINs and passwords can be physically or electronically sent to another individual as part of a vote selling attack, as described in Section 4.3.3 or in attempts to coerce voters, as described in Section 4.3.2. As noted in those sections, it is difficult to estimate the likelihood of such attacks or how motivated potential attackers would be to conduct these types of attacks. However, depending on the types of credentials used, these attacks could scale fairly well, potentially allowing individuals or organizations to collect large numbers of voters' credentials and cast votes on their behalf. ## 7.4.6 Security Awareness and Training Many of the threats described in this section are attacks on users, rather than on the voting system components. In some cases, users are not aware of the security threats faced by a system, or what actions might pose a security risk. Security awareness presentations and materials can educate users about these threats in the hopes that they will be less likely to fall to a phishing or social engineering attack and more likely to use safe computing behaviors. Security training can educate users about relevant security skills and competencies that are necessary for them to conduct their jobs effectively and safely.

In 1996, Congress enacted HIPAA [28] to reform the health care delivery system to improve portability and continuity of health insurance coverage in the group and individual markets [29] and to simplify the administration of health insurance. [30] Through subtitle F of HIPAA, Congress amended title XI of the Social Security Act of 1935 (SSA) by adding part C, entitled Administrative Simplification. [31] A primary purpose of part C is to improve the Medicare and Medicaid programs and the efficiency and effectiveness of the health care system, by encouraging the development of a health information system through the establishment of uniform standards and requirements for the electronic transmission of certain health information. [32] Congress recognized that the development of a health information system that enabled the electronic transmission of IIHI as required by HIPAA would pose risks to the privacy of confidential health information and viewed individual privacy, confidentiality, and data security as critical to support the shift from a paper-based recordkeeping system for health information to a digital one. [33] Congress intended for the law to enhance individuals' trust in health care providers, which required that the law provide additional protection for the confidentiality of IIHI. As described by a Member of Congress at the time of the law's passage: "[t]his standardization, however, accelerates the creation of large databases containing personally identifiable information. All this information is transmitted over electronic networks. We need to be very careful about how safe and secure that information is from prying eyes. Some of it may be extremely sensitive and could be used in a malicious or discriminatory manner. [34] Moreover, Congress considered that health care reform required an approach that would not compromise privacy as health information became more accessible. [35] Congress applied the Administrative Simplification provisions directly to three types of persons referred to in regulation as covered entities: health plans, health care clearinghouses, and health care providers who transmit information electronically in connection with a transaction for which HHS has adopted a standard. [36] Under HIPAA, covered entities are required to maintain reasonable and appropriate administrative, physical, and technical safeguards [37] to: (1) ensure the integrity and confidentiality of information; [38] (2) protect against any reasonably anticipated threats or hazards to the security or integrity of the information and unauthorized uses or disclosures of the information; [39] and (3) otherwise ensure compliance with HIPAA by the officers and employees of covered entities. [40] HIPAA required the Secretary to adopt uniform standards to enable health information to be exchanged electronically. [41] Congress also directed the Secretary to, among other things, adopt standards for the security of IIHI. [42]

The DIB CS/IA program will continue to evaluate outreach opportunities to enhance engagement with industry, to include industry associations. No change is made to the rule. Comment: Two comments recommended that the infrastructure of the internet be upgraded and that the rule should incorporate technology neutral terms. Response: Other activities within the Government are examining the infrastructure of the internet. The rule focuses on cyber threat sharing and the risk of compromise of DoD information that resides on, or transits, DIB unclassified information systems. No change is made to the rule. Regulatory Procedures Executive Orders 12866, Regulatory Planning and Review and 13563, Improving Regulation and Regulatory Review. It has been certified that 32 CFR part 236 does not: (a) Have an annual effect on the economy of \$100 million or more, or adversely affect in a material way, the economy; a section of the economy; productivity; competition; jobs; the environment; public health or safety; or State, local, or tribal Governments or communities; (b) Create a serious inconsistency, or otherwise interfere with, an action taken or planned by another Agency; (c) Materially alter the budgetary impact of entitlements, grants, user fees, or loan programs, or the rights and obligations of recipients thereof; or (d) Raise novel legal or policy issues arising out of legal mandates, the President's priorities, or the principles as set forth in these Executive Orders. Public Law 104-121 , Congressional Review Act (5 U.S.C. 801) It has been determined that 32 CFR part 236 is not a major rule under 5 U.S.C. 801 , enacted by Public Law 104-121 , because it will not result in an annual effect on the economy of \$100 million or more; a major increase in costs or prices for consumers, individual industries, Federal, State, or local Government agencies, or geographic regions; or significant adverse effects on competition, employment, investment, productivity, innovation, or on the ability of United States-based enterprises to compete with foreign-based enterprises in domestic and export markets. Sec. 202, Public Law 104-4 , Unfunded Mandates Reform Act. It has been certified that 32 CFR part 236 does not contain a Federal mandate that may result in expenditure by State, local and tribal Governments, in aggregate, or by the private sector, of \$100 million or more in any one year. Public Law 96-354, Regulatory Flexibility Act (5 U.S.C. 601) It has been certified that 32

CFR part 236 is not subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would not, if promulgated, have a significant economic impact on a substantial number of small entities. DIB participation in the DIB CS/IA Program is voluntary. Public Law 96-511, "Paperwork Reduction Act" (44 U.S.C. Chapter 35)

Assessing the SP 800-53 controls of the system itself should ideally have a continual assessment component utilizing a monitoring program [13]. Frequent automated checks or scans should be conducted to detect changes in the system (as part of the MONITOR step below). Logging data should be used to detect possible malicious behavior that requires further investigations or remediation. This assessment may also include active processes such as red team testing of the system as input into the assessments.

FDA recognizes that some facilities that are predominantly retail distribute some food to businesses (that then may further distribute the food before it is consumed) and that some facilities that are predominantly nonretail distribute some food to consumers. FDA concludes that to require such facilities to keep records of each individual recipient consumer would be too burdensome, and not necessary to help address credible threats of serious adverse health consequences or death to humans or animals. If a traceback or trace forward is necessary, FDA can learn from sickened consumers the sources of the food they purchased, or notify consumers generally about food that presents a threat. Therefore, FDA is changing the final rule from the proposal so that it does not require records of subsequent recipients for sales directly to consumers, regardless of whether the seller is a retailer or another type of entity. The final rule excludes persons who distribute food directly to consumers from keeping records of those transactions. Moreover, if a person prepares and sells food directly to consumers for immediate consumption, then those sales qualify for the restaurant exemption. However, persons who operate retail food establishments that distribute food to persons who are not consumers are subject to all of the requirements in subpart J of this final rule. However, the requirements in § 1.345 of the final rule to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients that are not consumers applies as to those transactions only to the extent the information is reasonably available. Furthermore, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements of subpart J of this final rule, except the record access provisions for existing records under §§ 1.361 and 1.363. 4. Fishing Vessels FDA received no comments on this issue and has made no changes to the definition for fishing vessels or to the exemption in the final rule. 5. Retail Facilities (Comment 38) One comment states that it operates a business that is essentially the same as any other retailer (although they sell to restaurants). Sales to its customers are recorded using a checkout register, and thus, it should not be required to keep records of individual items purchased by customers. Requiring such records from it, but not requiring retailers to keep such records, would be unfair and would be extremely burdensome.

, when access to accounting disclosures and access to or amendment of records would cause the identity of a confidential source to be revealed. Disclosure of the confidential source's identity not only will result in the Department breaching the express promise of confidentiality made to the source but it would impair the Department's future ability to compile investigatory material for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, Federal contracts, or access to classified information. Unless sources may be assured that a promise of confidentiality will be honored, they will be less likely to provide information considered essential to the Department in making the required determinations. (B) From 5 U.S.C. 552a(e)(1) , as in the collection of information for investigatory purposes, it is not always possible to determine the relevance and necessity of particular information in the early stages of the investigation. In some cases, it is only after the information is evaluated in light of other information that its relevance and necessity becomes clear. Such information permits more informed decision making by the Department when making required suitability, eligibility, and qualification determinations. § 310.22 Defense Security Service (DSS) exemptions. (a) General. The Director of the Defense Security Service establishes the following exemptions of records systems (or portions thereof) from the provisions of these rules, and other indicated portions of Public Law 93-579, in this section. They may be exercised only by the Director, Defense Security Service and the Chief of the Office of FOI and Privacy. Exemptions will be exercised only when necessary for a specific, significant and legitimate reason connected with the purpose of a records system, and not simply because they are authorized by statute. Personal records releasable under the provisions of 5 U.S.C. 552 will not be withheld from subject individuals based on these exemptions. (b) All

systems of records maintained by DSS shall be exempt from the requirements of 5 U.S.C. 552a(d) pursuant to 5 U.S.C. 552a(k)(1) to the extent that the system contains any information properly classified under Executive Order 12958 and which is required by the Executive Order to be withheld in the interest of national defense or foreign policy. This exemption, which may be applicable to parts of all systems of records, is necessary because certain record systems not otherwise specifically designated for exemptions herein may contain items of information that have been properly classified. (1) System identifier and name. V1-01, Privacy and Freedom of Information Request Records. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2)

This section contains a description of the proposed amendments to the Security Rule and the Department's rationale for its proposals. As part of this rationale, we often include a discussion of best practices contained in previously published guidance documents issued by the Department, NIST, and other Federal agencies. We request comment on previously published guidance documents that are not discussed herein that were issued by the Department or other Federal agencies and contain best practices but may be relevant or applicable to regulated entities, including the names of and citations for such guidance documents. We do not propose to adopt referenced best practices as the standard or implementation specifications unless otherwise specified in the proposed regulatory text. Rather, we include such discussion to provide regulated entities with context for the aforementioned proposals. We recognize that regulated entities are of varying types and sizes and may be concerned that requiring the adoption of such best practices might not be appropriate for all. However, we request comment on whether we should require implementation of certain aspects of a particular guidance document. If so, please explain which aspect(s) we should require, the rationale, and information about the burden of implementing such aspect(s).

A. Section 160.103-Definitions

1. Current Provision Electronic media are used by many health care organizations to process, transmit, and maintain ePHI. As defined by the Security Rule, the term "electronic media" [334] encompasses both (1) electronic storage material on which data is or may be electronically recorded; and (2) transmission media used to exchange information already in electronic storage media. It specifically excludes certain transmissions, such as those of paper, via facsimile ("fax"), and voice, via telephone, from being considered transmissions via electronic media if the information being exchanged did not exist in electronic form immediately before the transmission.

2. Issues To Address The Department revised the definition of "electronic media" in 2013 by replacing the term "electronic storage media" with "electronic storage material" in recognition that there may be storage material other than "media" that houses electronic data in the future. [335] At that time, the Department said that a fax machine accepting a hardcopy document for transmission is not a covered transmission even though the document may have originated from printing from an electronic file. [336] In response to commenter concerns, we also clarified that ePHI maintained, intentionally or otherwise, in a photocopier, fax machine, or other device is subject to the Security Rule and reminded regulated entities that they should be aware of the capabilities of such devices with respect to their ability to maintain ePHI. [337] Additionally, a regulated entity should consider the appropriateness of implementing security measures that account for such capabilities. [

means a discrete identifiable information and operational technology asset that represents a building block of a system and may include hardware, software, and firmware. Cyber supply chain risk means the potential for harm or compromise that arises as a result of cybersecurity risks from suppliers, their supply chains, and their products or services. This includes risks that arise from threats exploiting vulnerabilities or exposures within products and services traversing the supply chain as well as threats or exposures within the supply chain itself. The level of risk depends on the likelihood that relevant threats may exploit applicable vulnerabilities and the consequential potential impacts. (NIST SP 800-161 and 800-203).

Federal information system (1) Means an information system (44 U.S.C. 3502(8)) used or operated by an agency, by a contractor of an agency, or by another organization, on behalf of an agency; (2) On behalf of an agency as used in this definition, means when a contractor uses or operates an information system or maintains or collects information for the purpose of processing, storing, or transmitting Government data, and those activities are not incidental to providing a service or product to the Government (32 CFR part 2002).

Full access means, for all contractor information systems used in performance, or which support performance, of the contract (1) Physical and electronic access to (i) Contractor networks; (ii) Systems; (iii) Accounts with access to Government systems; (iv) Other infrastructure housed on the same computer network; (v) Other infrastructure with a shared identity

boundary or interconnection to the Government system; and (2) Provision of all requested Government data or Government-related data, including: (i) Images; (ii) Log files; (iii) Event information; and (iv) Statements, written or audio, of contractor employees describing what they witnessed or experienced in connection with the contractor's performance of the contract. Government data means any information, (including metadata), document, media, or machine-readable material regardless of physical form or characteristics that is created or obtained by the Government, or a contractor on behalf of the Government, in the course of official Government business. Government-related data means any information, document, media, or machine-readable material regardless of physical form or characteristics that is created or obtained by a contractor through the storage, processing, or communication of Government data. Government-related data does not include: (1) A contractor's business records (e.g., financial records, legal records) that do not incorporate Government data; or (2) Data such as operating procedures, software coding or algorithms that are not primarily applied to the Government data. High value asset

(1) Have at least one transducer (sensor or actuator) for interacting directly with the physical world, have at least one network interface, and are not conventional information technology devices, such as smartphones and laptops, for which the identification and implementation of cybersecurity features is already well understood; and (2) Can function on their own and are not only able to function when acting as a component of another device, such as a processor. Media means physical devices or writing surfaces including, but not limited to, magnetic tapes, optical disks, magnetic disks, large-scale integration memory chips, and printouts onto which information is recorded, stored, or printed within an information system (NIST SP 800-53). Metadata means information describing the characteristics of data including, but not limited to, structural metadata that describes data structures (e.g., data format, syntax, and semantics) and descriptive metadata that describes data contents (e.g., information security labels) (NIST SP 800-37). Operational technology (OT) means programmable systems or devices that interact with the physical environment or manage devices that interact with the physical environment. These systems or devices detect or cause a direct change through the monitoring and/or control of devices, processes, and events. Examples of operational technology include industrial control systems, building management systems, fire control systems, and physical access control mechanisms (NIST SP 800-160 vol 2). Overlay means a specification of security or privacy controls, control enhancements, supplemental guidance, and other supporting information employed during the tailoring process, that is intended to complement and further refine security control baselines. An overlay specification may be more stringent or less stringent than the original security control baseline specification and can be applied to multiple information systems (OMB Circular No. A-130). Telemetry means the automatic recording and transmission of data from remote or inaccessible sources to an information system in a different location for monitoring and analysis. Telemetry data may be relayed using radio, infrared, ultrasonic, cellular, satellite or cable, depending on the application. (b) Applicability. The requirements of this clause shall only apply to aspects of a Federal information system (FIS) that do not involve cloud computing services. (c) Records management and Government access. (1) The Contractor shall provide the Contracting Officer with all Government data and Government-related data in the format specified in the contract. (2) The Contractor shall dispose of Government data and Government-related data in accordance with the terms of the contract and provide the confirmation of disposition to the Contracting Officer in accordance with contract closeout procedures.

FDA has analyzed this final rule in accordance with the principles set forth in Executive Order 13132 . FDA has determined that the proposed rule does not contain policies that have substantial direct effects on the States, on the relationship between the National Government and the States, or on the distribution of power and responsibilities among the various levels of government. Accordingly, the agency concludes that the final rule does not contain policies that have federalism implications as defined in the Executive order and, consequently, a federalism summary impact statement is not required. XI. References The following references have been placed on display in the Division of Dockets Management (see ADDRESSES) and may be seen by interested persons between 9 a.m. and 4 p.m., Monday through Friday. (FDA has verified the Web site addresses, but we are not responsible for subsequent changes to the nonFDA Web sites after this document publishes in the Federal Register .) 1. Eastern Research Group, Small Business Model, 2003. 2. Estrin, A., Memo to Docket Summarizing Conversations Held Between May 15, 2003, and August 7, 2003, With Experts Jack Guzewich and Sarah Pichette; Also a Description of Data Obtained From FDA's Outbreak Investigations, February 6, 2004. 3. Mead, P.S., L. Slutaker, V. Dietz, et al., Food-Related Illness and Death in

the United States, · Emerging Infectious Diseases , Center for Disease Control and Prevention (CDC), vol. 5, no. 5, September-October 1999. 4. Finger, Anne L., Senior Editor, ·Primary Care: Where Do You Stand on the Pay Scale?· Medical Economics, (<http://www.memag.com/>), March 19, 2001. 5. Healthcare Cost and Utilization Project, Nation Inpatient Sample (NIS)·2001, Washington, DC, Agency for Healthcare Research and Quality, 2003. 6. FDA/CFSAN Bad Bug Book, accessed at <http://www.cfsan.fda.gov/~mow/intro.html> on May 3, 2004. 7. National Center for Infectious Diseases, Infectious Disease Information, CDC, accessed at <http://www.cdc.gov/ncidod/diseases/index.htm> on May 3, 2004. 8. ·Estimating the Value of Consumers' Loss from Foods Violating the FD&C Act·, Research Triangle Institute (RTI), vol. II, Final Report, September 1988. 9. ·Modeling the Effects of Food Handling Practices on the Incidence of Foodborne Illness·, Final Report Contract No. 223-01-2466, Task Order 1, With FDA Performed by RTI International, April 2003. 10. Brevard, Theresa A., et al, ·Acute Occupational Disinfectant-Related Illness Among Youth, 1993-1998·, Environmental Health Perspectives, vol. 111, no. 13, 2003. 11. ·Surveillance for Acute Insecticide-Related Illness Associated with Mosquito-Control Efforts·Nine States, 1999-2002·, Morbidity and Mortality Weekly Report, vol. 52, no. 27, pp. 629-634, July 11, 2003. 12. Kaplan, et al., ·The Quality of Well-Being Scale: Rationale for a Single Quality of Life Index·, Quality of Life Assessment: Key Issues in the 1990s , ed. Stuart R. Walker and Rachel M. Rosser, 1993.

(c) The agency point of contact shall return to the offeror any unsolicited proposal marked with an administrative marking different from that provided in paragraph (a) of this section. The return letter will state that the proposal cannot be considered because it is impracticable for the Government to comply with the administrative marking and that the agency will consider the proposal if it is resubmitted with the proper administrative marking. * * * * (f) When an agency receives an unsolicited proposal without any restrictive administrative marking from an educational or nonprofit organization or institution, and an evaluation outside the Government is necessary, the agency point of contact shall· (1) Attach a cover sheet clearly marked with the administrative marking in paragraph (d) of this section; (2) Change the beginning of this administrative marking by deleting ·All Government personnel· and adding ·All Government and non-Government personnel·; and (3) Require any non-Government evaluator to agree in writing that data in the proposal will not be disclosed to others outside the Government. * * * * PART 27·PATENTS, DATA AND COPYRIGHTS 31. Revise the heading of section 27.203 to read as follows: 27.203 Security requirements for patent applications and other patent information. * * * * 32. Redesignate sections 27.203-1 and 27.203-2 as sections 27.203-2 and 27.203-3, and adding a new section 27.203-1 to read as follows: 27.203-1 Security requirements for controlled unclassified information. Contracts involving patent applications or other patent-related controlled unclassified information require safeguarding or dissemination controls that must be identified in the SF XXX, Controlled Unclassified Information (CUI) Requirements. See 4.403. 33. Revise the heading of newly redesignated section 27.203-2 to read as follows: 27.203-2 Security requirements for classified information. * * * * PART 33·PROTESTS, DISPUTES, AND APPEALS 34. Amend section 33.104 by· a. Revising paragraph (a)(2); and b. Removing from paragraph (a)(5) introductory text the phrase ·development or commercial information· and adding ·development, commercial information, or other controlled unclassified information· in its place. The revision reads as follows: 33.104 Protests to GAO. * * * * (a)*** (2) Immediately after receipt of the GAO's written notice that a protest has been filed, the agency shall give notice of the protest to the contractor if the award has been made, or, if no award has been made, to all parties who appear to have a reasonable prospect of receiving award if the protest is denied. (printed page 4296) The agency shall furnish copies of the protest submissions to such parties with instructions to· (i) Communicate directly with the GAO; and

3.6.2 | Element-Level Judgment Assistance ... 3.6.2 Element-Level Judgment Assistance Each element has an associated discussion to assist in making a judgment.

·Not applicable· was removed from §·170.24(c)(9) for the case where the DoD CIO previously approved a variance. The rule has been updated to reflect the language of DFARS clause 252.204-7012 and the DoDAM, including nonapplicable or to have an alternative, but equally effective, security measure. Regarding the comment on N/A objectives, §·170.23 is clear that MET means all applicable objectives for the requirement and that if an objective does not apply, then it is equivalent to being MET. A security requirement can be applicable, even with one or more objectives that are N/A. The overall requirement is only NOT MET when one or more applicable objectives is not satisfied. The

determination of assessment findings is made by an Assessor following the assessment methodology. In the case of a self-assessment, the Assessor is from the OSA. In the case of a certification assessment, the Assessor is from the C3PAO or DIBCAC. An assessment finding of NOT APPLICABLE (N/A) means a security requirement (or assessment objective) does not apply at the time of the CMMC assessment. For each assessment objective or security requirement marked N/A, the Certified Assessor includes a statement that explains why it does not apply to the contractor. The OSC should document in its SSP why the security requirement does not apply and provide justification. There is no standard set of artifacts required to justify a finding of N/A. A System Security Plan as described in security requirement CA.L2-3.12.4 is required to conduct an assessment. The rule has been updated at § 170.24(c)(2)(i)(B)(6) for clarity. Security requirement CA.L2-3.12.4 does not have an associated point value. The OSA will not receive a -1 for a missing or incomplete SSP. The absence of an up-to-date system security plan at the time of the assessment would result in a finding that 'an assessment could not be completed due to incomplete information and noncompliance with DFARS clause 252.204-7012.' The rule has been updated in § 170.24(c)(6) to clarify this.

e. Artifacts

Comment: Several comments and requests for clarification dealt with artifacts that are reviewed or created during a CMMC assessment, or as part of compliance with other contractual requirements, including DFARS clause 252.204-7012. Some commenters asked whether standardized SSP and POA&M templates would be provided to assist with compliance. Other templates requested included pre-assessment planning materials, final assessment reports, and the resulting Certificate of CMMC Status.

We recognize that emergencies or other occurrences may render it infeasible for a regulated entity to use MFA, so we propose a second exception for when MFA is infeasible during an emergency or other occurrence that adversely affects the regulated entity's relevant electronic information systems or the confidentiality, integrity, or availability of ePHI. [779] For the proposed exception to apply, a regulated entity would be required to implement reasonable and appropriate compensating controls in accordance with its contingency plan [780] and emergency access procedures. [781] For example, if an optical scanner used by a regulated entity as one of the required factors for MFA is rendered inoperable (e.g., is temporarily broken or adversely affected by a cyberattack), a compensating control may be to temporarily allow users to log in with their user name and a unique password, rather than with a PIN and retinal scan. The Department would make this proposed exception applicable only for the limited period of time in which MFA is infeasible for the regulated entity during the emergency or other occurrence, regardless of whether the emergency or other occurrence continues. At proposed 45 CFR 164.312(f)(2)(iii)(C) , we propose three exceptions that would be for a technology asset in use that is a device within the meaning of section 201(h) of the Food, Drug, and Cosmetic Act that has been authorized for marketing by the FDA. The first would be for a device authorized by the FDA for marketing pursuant to a submission received before March 29, 2023, while the second would be for a device authorized by the FDA for marketing pursuant to a submission received on or after March 29, 2023, that is no longer supported by its manufacturer. In both cases, the exception would only apply where, the regulated entity has deployed any updates or patches required or recommended by the manufacturer of the device. Similar to our proposal for exceptions to encryption at proposed 45 CFR 164.312(b)(3)(iv)(A) and (B) , we recognize that some regulated entities may incur costs of replacing legacy devices because of the limitations on the proposed exception to MFA where a device was submitted to the FDA for authorization before March 29, 2023 or a device submitted for authorization on or after that date that is no longer supported by its manufacturer. [782] However, as discussed above, such devices can pose significant risks to the confidentiality, integrity, and availability of ePHI. [783]

(4) Notification sent to the last known address of the individual as reflected in the records is considered a reasonable effort to notify. (5) Make a disclosure accounting each time a record is disclosed under a court order or compulsory legal process. (I) Disclosures to Consumer Reporting Agencies. (1) Certain personal information may be disclosed to consumer reporting agencies as provided in the Federal Claims Collection Act (31 U.S.C. 3711(e)). (2) Under the provisions of paragraph (I)(1) of this section, the following information may be disclosed to a consumer reporting agency: (i) Name, address, taxpayer identification number (SSN), and other information necessary to establish the identity of the individual. (ii) The amount, status, and history of the claim. (iii) The Agency or program under which the claim arose. (3) The Federal Claims Collection Act (31 U.S.C. 3711(e)) requires the system notice for the system of records from which the information will be disclosed, indicates that the information may be disclosed to a consumer reporting agency.

§ 310.23 Disclosures to commercial enterprises. (a) General policy. (1) Make releases of personal information to commercial enterprises under the criteria established by 32 CFR part 286 . (2) The relationship of commercial enterprises to their clients or customers and to the Department of Defense is not changed by this part. (3) The DoD policy on personal indebtedness for military personnel is contained 32 CFR part 112 , 'Indebtedness of Military Personnel,' and for civilian employees in 5 CFR part 735 . (b) Release of personal information. (1) Any information that must be released under 32 CFR part 286 , the 'DoD Freedom of Information Act Program,' may be released to a commercial enterprise without the individual's consent (see paragraph (b) of § 310.22). (2) Commercial enterprises may present a signed consent statement setting forth specific conditions for release of personal information. Statements such as the following, if signed by the individual, are considered valid: I hereby authorize the Department of Defense to verify my Social Security Number or other identifying information and to disclose my home address and telephone number to authorized representatives of (name of commercial enterprise) so that they may use this information in connection with my commercial dealings with that enterprise. All information furnished shall be used in connection with my financial relationship with (name of commercial enterprise). (3) When a statement of consent as outlined in paragraph (b)(2) of this section is presented, provide the requested information if its release is not prohibited by some other regulation or statute. (4) Blanket statements of consent that do not identify the Department of Defense or any of its Components, or (printed page 18774)

manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that contacts food and foreign based transporters that transport food in the United States are assumed to not incur additional records maintenance costs. FDA assumes the 34,634 convenience store facilities will spend 2.5 hours per year and that persons who directly market food are excluded from the rule. All other facilities (344,859) will spend 13 hours per year on additional records maintenance at an hourly cost of \$25.10. The undiscounted total additional records maintenance costs 2 years following enactment of the rule are \$70,745,000. After 3 years, and for each subsequent year, the undiscounted additional records maintenance costs are \$114,701,000. The annual costs for records access planning and for records retention for all persons are assumed to be zero in the final rule. The following table includes the estimated reduction in benefits relative to the proposal from policy options that would exclude select sectors from recordkeeping requirements, or that would relax certain provisions, which are considered in detail earlier in this analysis. The benefits from each policy option are ranked by size, so that policy options that would result in large reductions in benefits relative to the proposal are ranked highest, where a ranking of one represents the largest reduction in benefits relative to the proposal. The reduction in benefits from relaxing the requirement for all persons to establish and maintain records containing lot numbers is very high. With lot codes contained on all records, the duration of a traceback investigation for many products would likely be between 1 and 14 days (estimated current times for many packaged products that contain all lot code information on the package). Relaxing the lot code requirement may increase the traceback times of these products to between 6 to 8 weeks (estimated current times for many fresh products not accompanied by lot code information). Relaxing the requirement for all records to contain lot code information leads to the largest reduction in benefits relative to the baseline.

) An assessment and documentation of the security measures the covered entity or business associate uses to ensure the confidentiality, integrity, and availability of the electronic protected health information created, received, maintained, or transmitted by the covered entity or business associate. (5) A reasonable determination of the likelihood that each threat identified in accordance with paragraph (a)(2)(ii)(A)(2) of this section will exploit the vulnerabilities identified in accordance with paragraph (a)(2)(ii)(A)(3) of this section. (6) A reasonable determination of the potential impact of each threat identified in accordance with paragraph (a)(2)(ii)(A)(2) of this section successfully exploiting the vulnerabilities identified in accordance with paragraph (a)(2)(ii)(A)(3) of this section. (printed page 1013) (7) An assessment of risk level for each threat identified in accordance with paragraph (a)(2)(ii)(A)(2) of this section and vulnerability identified in accordance with paragraph (a)(2)(ii)(A)(3) of this section, based on the determinations made in accordance with paragraphs (a)(2)(ii)(A)(5) and (6) of this section. (8) An assessment of the risks to electronic protected health information posed by entering into or continuing a business associate contract or other written arrangement with any prospective or current business associate, respectively, based on the written verification obtained from the prospective or current business associate in accordance with

paragraph (b)(1) of this section. (B) Maintenance. Review, verify, and update the written assessment on an ongoing basis, but at least once every 12 months and, in accordance with paragraph (a)(1)(ii)(C)(2) of this section, in response to a change in the covered entity's or business associate's environment or operations that may affect electronic protected health information. (3) Standard: Evaluation ·(i) General. Perform a written technical and nontechnical evaluation to determine whether a change in the covered entity's or business associate's environment or operations may affect the confidentiality, integrity, or availability of electronic protected health information. (ii) Implementation specifications ·(A) Performance. Perform a written technical and nontechnical evaluation within a reasonable period of time before making a change in the covered entity's or business associate's environment or operations as described in paragraph (a)(1)(ii)(C)(2) of this section. (B) Response. Respond to the written technical and nontechnical evaluation in accordance with the covered entity's or business associate's risk management plan required by paragraph (a)(5)(ii)(A) of this section. (4) Standard: Patch management ·(i) General. Implement written policies and procedures for applying patches and updating the configuration(s) of the covered entity's or business associate's relevant electronic information systems. (ii) Implementation specifications ·(A) Policies and procedures.

This publication describes an approach for the development of Information Security Continuous Monitoring (ISCM) program assessments that can be used to evaluate ISCM programs within federal, state, and local governmental organizations and commercial enterprises. An ISCM program assessment provides organizational leadership with information on the effectiveness and completeness of the organization's ISCM program, including the review of ISCM strategies, policies, procedures, operations, and analysis of continuous monitoring data. The ISCM assessment approach can be used as presented or as the starting point for an organization-specific methodology. It includes example evaluation criteria and assessment procedures that can be applied to organizations. Organizations need a way to determine and evaluate if an established ISCM program is effectively managing the organization's security posture commensurate with risk. This publication describes one approach to developing an ISCM program assessment based on evaluation criteria derived from multiple sources, (including NIST Special Publications (SP) 800-137, Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations, SP 800-37, Risk Management Framework for Information Systems and Organizations: A Life Cycle Approach for Security and Privacy, SP 800-39, Managing Information Security Risk: Organization, Mission and Information System View, and Office of Management and Budget (OMB) Circulars and Memoranda). An ISCM program assessment developed under guidance in this publication evaluates the ISCM program itself (i.e., the structure and governance of the ISCM program), not the results of the ISCM program or the continuous monitoring technologies used. An effective ISCM program assessment provides consistent results regardless of the entity conducting the assessment.

3.6.4 | Secure Subsystem Approach | 10-11 10-11 | | 3. 3.6.4 Secure Subsystem Approach : TSie idea behind the secure subsystem approach is to have the host operating system environment so configured that only the data management system may be used.

(d) When a DoD Component makes a determination to grant a request for access in whole or in part, the DoD Component shall notify the requester in writing or simply provide the requested record. The response to the request may be made in lieu of the acknowledgment of receipt provided the response will be made within 10 days (excluding Saturdays, Sundays, and legal public holidays). The DoD Component shall inform the requester of any fee charged for duplication of the record(s). If the request is made in person, the individual may receive the records directly in a manner not unreasonably disruptive of the DoD Component's operations, upon payment of any applicable fee. If the individual is accompanied by another person, the individual may be required to authorize in writing any discussion of the records in the presence of the other person. (e) A DoD Component denying a request for access in any respect shall notify the requester of that determination in writing. (1) The notice of denial consists of: (i) A determination to withhold any requested record in whole or in part; (ii) A determination that a requested record does not exist or cannot be located; or (iii) A determination that what has been requested is not a record subject to the Privacy Act. (2) The denial notification letter shall be signed by the head of the DoD Component, or the DoD Component head's designee, and shall include: (i) The date of the denial; (ii) A brief statement of the reason(s) for the denial, including any Privacy Act exemption(s) applied by the DoD Component in denying the request; and (iii) A statement that the denial can be appealed within 60 calendar days in accordance with § 310.6. The statement will include the position title and the

address of the appellate authority. § 310.6 Appeals from denials of requests for access to records. (a) If the requester is dissatisfied with a DoD Component's response, the requester can appeal an adverse determination denying the request to the appellate authority listed in the notification of denial letter. The appeal must be made in writing, and it must be postmarked within 60 calendar days of the date of the letter denying the initial request for records. The letter of appeal should include a copy of the DoD Component's determination (including the assigned request number, if known). For the quickest possible handling, the appeal letter and the envelope should be marked: ·Privacy Act Appeal·.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The author, Vincent C. Hu of the National Institute of Standards and Technology (NIST), wishes to thank Isabel Van Wyk and Jim Foti (NIST) who reviewed drafts of this document. The author also gratefully acknowledges and appreciates the comments and contributions made by government agencies, private organizations, and individuals in providing direction and assistance in the development of this document.

Numerous comments asked the DoD to expand on the definition, explanation, and guidance for Security Protection Data (SPD) and Security Protection Assets (SPA). Several other comments requested that the rule and supplemental documents add or expand definitions for ·Asset·, including various specific types of assets like ·Technology Assets·, ·Personnel Assets·, ·Organizational Assets·, ·Specialized Assets·. Some comments asked to modify the definition for ·Security Protection Asset·, ·CUI Asset·, ·FCI Asset·, and ·Out-of-Scope Assets·. Response: The DoD modified the rule to add a definition for ·Security Protection Data (SPD)·. The DoD considered the NIST definitions for ·System Information· and ·Security Relevant Information· in the development of the new SPD definition. CMMC does not regulate the OSA's SPD, but instead implements existing regulatory requirements for the safeguarding of CUI. The DoD does not agree with the statement that the ESP definition conflates SPA with CUI assets. The definition of Security Protection Assets is consistent with its application in the NIST SP 800-171 R2 abstract. The phrase ·FCI Assets are part of the Level 1 CMMC Assessment Scope and are assessed against all CMMC Level 1 requirements· was removed from the rule. The DoD declined to rephrase the term ·CUI Assets·. The DoD reviewed the recommended edit and declined to make an update to ·Out-of-Scope Assets·. The definition, as written, provides a clear distinction with Security Protection Assets (SPAs). b. Senior Official Comment: Several comments asked for additional definition or guidance about the Senior Official role. Response: The DoD modified the rule to replace all references to the ·Senior Official· with ·Affirming Official· and provided additional clarity on this term. It is beyond the purview of the DoD to define technical qualifications for an OSA Affirming Official. c. ESP/CSP/MSP Comment: Some comments asked for additional clarification of the terms related to External Service Providers (ESPs) and Cloud Service Providers (CSPs). Two comments requested the rule add a definition and acronym for ·Managed Service Provider·. Response: The DoD received numerous comments about the use of ESPs which do not process, store, or transmit CUI. In response to these comments, the DoD modified the rule to reduce the assessment burden on ESPs. An ESP that utilizes staff augmentation, where the OSA provides all processes, technology, and facilities, does not require a CMMC assessment. The rule was also updated to add a definition of ·CSP· that is based on the NIST SP 800-145 Sept2011 definition of cloud computing. The term ·Managed Service Provider· is not used in the rule; therefore, the acronym was removed from § 170.4. d. IoT/OT/ICS Comment: Several comments recommended DoD clarify the definition of IoT, OT, and ICS. Regarding IoT, one comment requested the rule specify that the exchange of data and information between devices occurs over the internet. Response:

This guidance applies to contracts involving a custom-build system. Contractors will reference the current version of this guidance for considerations, concepts, tasks, and activities to be taken when designing a system. As such, the Government assumes all 6 contractors awarded a contract involving a custom-build, non-cloud FIS will expend effort to read and familiarize themselves with the publication and make any requisite adjustments to their security design process to be compliant with the guidance. It is estimated that a contractor will expend approximately 40 hours reading to become more familiar and adjusting the FIS design process to comply with NIST SP 800-160 Volume 1 in year one. Using an average loaded wage rate of \$91.10 for FIS occupations, the total estimated labor cost for a contractor to comply with NIST SP 800-160 Volume 1 is approximately \$3,600 (40 hours * \$91.10). vii. NIST SP 800-160, Volume 2. When requested by the Government, contractors will reference the current version of this guidance to select, adapt, and use cyber resiliency constructs for new systems, system upgrades, or repurposed systems. This guidance applies to contracts involving a custom-build system. As such, the Government assumes all 6 contractors awarded a (printed page 68408) contract involving a custom-build, non-cloud FIS will expend effort to read and become more familiar with the publication. It is estimated that a contractor will expend approximately 16 hours reading NIST SP 800-160 Volume 2 to become more familiar with its requirements in year one. Using an average loaded wage rate of \$91.10 for FIS occupations, the total estimated labor cost for a contractor to comply with NIST SP 800-160 Volume 2 is \$1,500(16 hours * \$91.10). viii. NIST SP 800-30. Contractors will reference the current version of this guidance to develop and ensure existing processes prepare for, conduct, communicate results from, and maintain risk assessments over time. This guidance is applicable to all contracts involving a custom-build system, as these processes will need to be developed for those FIS, as well as some contracts involving existing systems where current processes need to be modified to comply with the guidance. As such, the Government assumes all 6 contractors awarded a contract involving a custom-build, non-cloud FIS, and 4 (20 percent * 22) contractors awarded a contract involving an existing, non-cloud FIS will expend effort to read and better familiarize themselves with the publication and develop new or adapt existing processes to the guidance of NIST SP 800-30.

(2) Before issuing a solicitation for the procurement of an end product identified by a material identifier that is available as described at PGI 204.7603, the contracting officer shall ensure a SPRS item risk search has been performed and shall consider any item risk warnings provided. When evaluating quotations or offers for an end product identified by a material identifier, a SPRS item risk search is required for any end product that did not have an item risk search performed prior to solicitation. If there are item risk warnings, the contracting officer shall consider strategies to mitigate risk, such as the following: (i) Consulting with the program office. (ii) Including mitigating requirements in the statement of work, as provided by the requiring activity. (iii) Including FAR and DFARS clauses identified in the SPRS application, as appropriate. (b) Price risk. (1) When procuring a service or an end product identified by a material identifier that is available as described at PGI 204.7603, the contracting officer shall consider price risk assessment in determining if a proposed price is consistent with historical prices paid for an item or otherwise creates a risk to the Government. Contracting officers shall not rely solely on the price risk assessment when determining prices to be fair and reasonable. (2) The contracting officer shall consider strategies to mitigate price risk, such as the following: (i) Not awarding to offerors or quoters with high risk price ratings unless there is a way to justify the price through additional price or cost analysis. (ii) Utilizing appropriate price negotiation techniques and procedures. (iii) Using price reasonableness or price realism techniques at FAR 13.106 or 15.4. See also 215.403-3 when making award decisions. (c) Supplier risk. The contracting officer shall consider supplier risk, to assess the risk of unsuccessful performance and supply chain risk, in award decisions. Supplier risk assessments in SPRS include quality, delivery, and other contractor performance information. 204.7604 Solicitation provision. Except for supplies or services exempted by DoDI 5000.79, use the provision at 252.204-7024, Notice on the Use of the Supplier Performance Risk System, in solicitations for supplies and services, including solicitations using FAR part 12 procedures for the acquisition of commercial products and commercial services. PART 208-REQUIRED SOURCES OF SUPPLIES AND SERVICES 3. Amend section 208.405 by adding paragraph (4) to read as follows: 208.405 Ordering procedures for Federal Supply Schedules. * * * * (4) See 204.7603 for procedures on the required use of the Supplier Performance Risk System (SPRS) risk assessments. (i) The contracting officer shall ensure SPRS assessments of price risk and supplier risk are considered as a part of the award decision. (printed page 17339)

the enterprise's email gateway. Implementation Groups: 2,3 Asset Type: network Security Function: protect Parent Control: Email and Web Browser Protections

AU.L2-3.3.9 · Audit Management CMMC Assessment Guide · Level 2 | Version 2.13 90 FURTHER DISCUSSION Companies should restrict access to audit logging functions to a limited number of privileged users who can modify audit logs and audit settings. General users should not be granted permissions to perform audit management. All audit managers should be privileged users, but only a small subset of privileged users will be given audit management responsibilities. Functions performed by privileged users must be distinctly separate from the functions performed by users who have audit-related responsibilities to reduce the potential of fraudulent activities by privileged users not being detected or reported. When possible, individuals who manage audit logs should not have access to other privileged functions. Example You are responsible for the administration of select company infrastructure that contains CUI, but you are not responsible for managing audit information. You are not permitted to review audit logs, delete audit logs, or modify audit log settings [b]. Full control of audit logging functions has been given to senior system administrators [a,b]. This separation of system administration duties from audit logging management is necessary to prevent possible log file tampering. Potential Assessment Considerations · Are audit records of nonlocal accesses to privileged accounts and the execution of privileged functions protected [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.3.9

IR.L2-3.6.1 · Incident Handling CMMC Assessment Guide · Level 2 | Version 2.13 136 Incident Response (IR) IR.L2-3.6.1 · INCIDENT HANDLING Establish an operational incident-handling capability for organizational systems that includes preparation, detection, analysis, containment, recovery, and user response activities. ASSESSMENT OBJECTIVES [NIST SP 800-171A]120 Determine if: [a] an operational incident-handling capability is established; [b] the operational incident-handling capability includes preparation; [c] the operational incident-handling capability includes detection; [d] the operational incident-handling capability includes analysis; [e] the operational incident-handling capability includes containment; [f] the operational incident-handling capability includes recovery; and [g] the operational incident-handling capability includes user response activities. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]120 Examine [SELECT FROM: Incident response policy; contingency planning policy; procedures addressing incident handling; procedures addressing incident response assistance; incident response plan; contingency plan; system security plan; procedures addressing incident response training; incident response training curriculum; incident response training materials; incident response training records; other relevant documents or records]. Interview [SELECT FROM: Personnel with incident handling responsibilities; personnel with contingency planning responsibilities; personnel with incident response training and operational responsibilities; personnel with incident response assistance and support responsibilities; personnel with access to incident response support and assistance capability; personnel with information security responsibilities]. Test [SELECT FROM: Incident-handling capability for the organization; organizational processes for incident response assistance; mechanisms supporting or implementing incident response assistance]. 120 NIST SP 800-171A, p. 36.

The Department believes it is important to clarify that the requirements of the Security Rule do not only apply to electronic information systems that create, receive, maintain, or transmit ePHI. After all, cybercriminals may be able to access ePHI by leveraging vulnerabilities in some electronic information systems that do not themselves create, receive, maintain, or transmit ePHI where such information systems are connected to or otherwise affect electronic information systems that do create, receive, maintain, or transmit ePHI. For example, while a payment processing system used in a covered entity's food and beverage outlets or gift shops may not create, receive, maintain, or transmit ePHI, it may affect the confidentiality, integrity, or availability of ePHI in certain circumstances, such as where such systems are connected to the same network as servers that contain ePHI. [378] Accordingly, we would interpret an electronic information system as otherwise affecting the confidentiality, integrity, or availability of ePHI if it is insufficiently segregated physically and electronically from an electronic information system that creates, receives, maintains, or transmits ePHI or one that otherwise affects the confidentiality, integrity, or availability of ePHI. An electronic information system would also fit the category of ·otherwise affecting· if it contains information that relates to an electronic information system that creates, receives, maintains, or transmits ePHI or to another electronic information system that otherwise affects the confidentiality, integrity, or availability of ePHI. For example, a compromised

electronic information system used to provide administrative functions, such as user authentication or management of storage area network infrastructure, that does not contain ePHI may allow unauthorized access to ePHI (affecting the confidentiality of ePHI) or disruption of storage configuration data (affecting the integrity and availability of ePHI). An electronic information system that is not connected to a covered health care provider's EHR but that maintains user IDs and passwords for the EHR also may not create, receive, maintain, or transmit ePHI; however, the confidentiality, integrity, or availability of the ePHI in the EHR would be affected if an unauthorized person gained access to that electronic information system. And the same is true for an electronic information system that contains the decryption keys for a regulated entity's encryption algorithms. Thus, it is important that administrative, physical, and technical safeguards be implemented not only for electronic information systems that create, receive, maintain, or transmit ePHI, but also for electronic information systems that otherwise affect the confidentiality, integrity, or availability of ePHI. (printed page 928) 14. Adding a Definition of 'Risk' a. Issues To Address

to require a regulated entity to configure and implement technical controls to install software patches and critical updates in a timely manner in accordance with the regulated entity's patch management program. [811] The proposed standard for patch management, an administrative safeguard discussed above, would require a regulated entity to establish and implement written policies and procedures for applying patches and updating relevant electronic information system configurations, while this proposal would require the regulated entity to implement technical controls to implement those written policies and procedures. In other words, proposed 45 CFR 164.312(h)(2)(iv) addresses the technical controls to effectuate a regulated entity's patch management plan. Applying patches for technology assets, including workstations, is an effective mechanism to mitigate known vulnerabilities and limit the risk of exploitation. [812] Although older applications or devices may no longer be supported with patches for new vulnerabilities, regulated entities still must take appropriate action if a newly discovered vulnerability affects an older application or device. If an obsolete, unsupported system cannot be upgraded or replaced, additional safeguards should be implemented or existing safeguards enhanced to mitigate known vulnerabilities until upgrade or replacement can occur (e.g., increase access restrictions, remove or restrict network access, disable unnecessary features or services). [813] Deployment of such technical controls would help to ensure that a regulated entity's relevant electronic information systems are updated as quickly as possible after a vulnerability has been identified and a patch released. The proposed standard for patch management, discussed above, would work in tandem with the proposed standard for vulnerability management to ensure that regulated entities substantially reduce the risk to ePHI from known vulnerabilities. [814] Together, these proposals would clarify that a regulated entity is required to affirmatively seek out information about known vulnerabilities, assess the risks to the confidentiality, integrity, and availability of ePHI, and implement effective mechanisms through both policies and procedures and technical controls to reduce the risk, as well the actual occurrence, of breaches resulting from known vulnerabilities. For example, known vulnerabilities should be readily identified by a regulated entity through monitoring of (printed page 979)

As a result, when an adversary's attack on one supplier causes it to shut down, the defender can increase its use of the other suppliers, thus shortening the time when it is without the critical components. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025

(B) From subsection (d) because the application of these provisions could impede or compromise an investigation or prosecution if the subject of an investigation had access to the records or were able to use such rules to learn of the existence of an investigation before it would be completed. In addition, the mere notice of the fact of an investigation could inform the subject and others that their activities are under or may become the subject of an investigation and could enable the subjects to avoid detection or apprehension, to influence witnesses improperly, to destroy evidence, or to fabricate testimony. (C) From subsection (e)(1) because during an investigation it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. In other cases, what may appear to be a relevant and necessary piece of information may become irrelevant in light of further investigation. In addition, during the course of an investigation, the investigator may obtain

information that related primarily to matters under the investigative jurisdiction of another agency, and that information may not be reasonably segregated. In the interest of effective law enforcement, DSS investigators should retain this information, since it can aid in establishing patterns of criminal activity and can provide valuable leads for Federal and other law enforcement agencies. (D) From subsections (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f) because this system is exempt from subsection (d) of the Act, concerning access to records. These requirements are inapplicable to the extent that these records will be exempt from these subsections. However, DSS has published information concerning its notification and access procedures, and the records source categories because under certain circumstances, DSS could decide it is appropriate for an individual to have access to all or a portion of his/her records in this system of records. (6) [Reserved]

§ 310.23 Defense Threat Reduction Agency (DTRA) exemptions. (a) Exemption for classified material. All systems of records maintained by the Defense Threat Reduction Agency shall be exempt under section (k)(1) of 5 U.S.C. 552a, to the extent that the systems contain any information properly classified under E.O. 12598 and that is required by that E.O. to be kept secret in the interest of national defense or foreign policy. This exemption is applicable to parts of all systems of records including those not otherwise specifically designated for exemptions herein which contain isolated items of properly classified information. (1) System identifier and name. HDTRA 007, Security Operations. (i) Exemption. Portions of this system of records may be exempt from the provisions of 5 U.S.C. 552a(c)(3), (d)(1) through (d)(4), (e)(1), (e)(4)(G), (H), (I), and (f). (ii) Authority.

These competencies pulled from a 2011 U.S. Office of Personnel Management (OPM) memorandum that introduced a 'Competency Model for Cybersecurity,' which itself followed a coordinated effort with the Federal Chief Information Officers (CIO) Council and NICE in November 2009 [3]. 3 The OPM model presented 117 competencies related to four occupation series and the pay grades of personnel in those occupations. A subject matter expert panel review of the OPM model conducted at that time identified 50 competencies to align with the NICE Framework KSAs found in five of the seven categories of work. 4 3 Berry, J. (2011, February 16). U.S. Office of Personnel Management Memorandum. Competency model for cybersecurity. Retrieved February - [1] Petersen R, Santos D, Wetzel K, Smith M, Witte G (2020) Workforce Framework for Cybersecurity (NICE Framework). (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-181, Rev. 1. <https://doi.org/10.6028/NIST.SP.800-181r1> - [2] National Institute of Standards and Technology (2021) NICE Framework Resource Center. Available at <https://www.nist.gov/itl/applied-cybersecurity/nice/resources> - [3] Berry J (2011) Competency Model for Cybersecurity . (U.S. Office of Personnel Management, Washington, DC), U.S. Office of Personnel Management Memorandum, February 16, 2011. Available at <https://www.chcoc.gov/content/competency-modelcybersecurity>

Back to Citation 679. Id. Back to Citation 680. Id. at 9. Back to Citation 681. Id. at 10. Back to Citation 682. 45 CFR 164.312(e)(2)(i). Back to Citation 683. 68 FR 8334, 8357 (Feb. 20, 2003). Back to Citation 684. For example, the ONC Health IT Certification Program requires that certified health IT certified to the end-user device encryption certification criterion at 45 CFR 170.315(d)(7) must encrypt electronic health information stored on end-user devices after use of the technology on those devices stops or prevent electronic health information from being locally stored on end-user devices after use of the technology on those devices stops. See also Security Standards: Technical Safeguards, supra note 343, p. 7. Back to Citation 685. How to Protect the Data that is Stored on Your Devices, Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security (access July 26, 2024), <https://www.cisa.gov/resources-tools/training/how-protect-data-stored-your-devices>; see also Karen Scarfone, et al., [Information Technology Laboratory (ITL)] Bulletin: August 2020, Security Considerations for Exchanging Files Over the internet, National Institute of Standards and Technology, U.S. Department of Commerce (Aug. 2020), <https://csrc.nist.gov/files/pubs/shared/itlb/itlb2020-08.pdf>. Back to Citation 686. 45 CFR 164.306(d). Back to Citation 687. Banner Health, supra note 567. Back to Citation 688. Resolution Agreement, Lifespan, Office for Civil Rights, U.S. Department of Health and Human Services (June 26, 2020), <https://www.hhs.gov/sites/default/files/lifespan-ra-cap-signed.pdf>. Back to Citation 689. Resolution Agreement, Yakima Valley Memorial Hospital, Office for Civil Rights, U.S. Department of Health and Human Services (May 15, 2023), <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/yakima-ra-cap/index.html>. Back to Citation 690. Id. Back to Citation 691. See Montefiore Medical Center, supra note 248. Back to Citation 692. See, e.g., HHS Office for Civil Rights

Settles HIPAA Investigation with Arizona Hospital System Following Cybersecurity Hacking, supra note 570. Back to Citation 693. Id. Back to Citation 694. The Home Depot Reports Findings in Payment Data Breach Investigation, Home Depot (Nov. 6, 2014), <https://ir.homedepot.com/news-releases/2014/11-06-2014-014517315>. Back to Citation 695. See 45 CFR 164.304 (proposed definitions of Deploy and Implement). Back to Citation 696. Security Standards: Technical Safeguards, supra note 343, p. 3. Back to Citation 697. Id. at 4. Back to Citation 698. Cybersecurity Performance Goals, supra note 18. Back to Citation 699. Id. at 3-4. Back to Citation 700. See 45 CFR 164.308(a)(4) and proposed 45 CFR 164.308(a)(10). Back to Citation 701. See Controlling Access to ePHI: For Whose Eyes Only?, supra note 416. Back to Citation 702. Defending Against Common Cyber-Attacks, supra note 396. Back to Citation 703. See 45 CFR 170.315(d)(1).

(k)(4) and (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3); (d)(1), (d)(2), (d)(3), (d)(4), (d)(5); (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I); (f)(1), (f)(2), (f)(2), (f)(3), (f)(4), (f)(5). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5). (iii) Reasons. The reasons for asserting these exemptions are to ensure the integrity of an investigative or administrative process and to protect (printed page 14775) statistical records. The execution requires that information be provided in a free and open manner without fear of retribution or harassment in order to facilitate a just, thorough, and timely resolution during an investigation or administrative action. Disclosures from this system can enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying, or fabricating evidence or documents. In addition, disclosures can subject sources and witnesses to harassment or intimidation which may cause individuals to not seek redress for concerns about occupational safety, health, environmental issues and accident reporting. Information is used to comply regulatory reporting requirements. § 310.21 Defense Logistics Agency (DLA) exemptions. (a) The Director, DLA or designee may claim an exemption from any provision of the Privacy Act from which an exemption is allowed. (b) An individual is not entitled to access information that is compiled in reasonable anticipation of a civil action or proceeding. The term civil action or proceeding is intended to include court proceedings, preliminary judicial steps, and quasi-judicial administrative hearings or proceedings (i.e., adversarial proceedings that are subject to rules of evidence). Any information prepared in anticipation of such actions or proceedings, to include information prepared to advise DLA officials of the possible legal or other consequences of a given course of action, is protected. The exemption is similar to the attorney work-product privilege except that it applies even when the information is prepared by non-attorneys. The exemption does not apply to information compiled in anticipation of criminal actions or proceedings. (c) Exempt Records Systems. All systems of records maintained by the Defense Logistics Agency will be exempt from the access provisions of 5 U.S.C. 552a(d) and the notification of access procedures of 5 U.S.C. 552a(e)(4)(H) pursuant to 5 U.S.C. 552a(k)(1) to the extent that the system contains any information properly classified under Executive Order 13526 and which is required by the Executive Order to be kept secret in the interest of national defense or foreign policy. This exemption, which may be applicable to parts of all DLA systems of records, is necessary because certain record systems not otherwise specifically designated for exemptions herein may contain isolated items of information which have been properly classified. (1) System identifier and name. S170.04 (Specific exemption), Debarment and Suspension Files. (i)

(G) For records that are copies of exempt records from external systems of records, such records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record that is now contained in this system of records. In general, the exemptions were claimed to properly protect classified information relating to national defense and foreign policy; to avoid interference during the conduct of criminal, civil, or administrative actions or investigations; to ensure protective services provided to the President and others are not compromised; to protect records used solely as statistical records; to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations; to preserve the confidentiality and integrity of Federal testing materials; and to safeguard evaluation materials used for military promotions when provided by a confidential source. The exemption rule for the original records will identify the specific reasons the records are exempt from specific provisions of 5 U.S.C. 552a. (h) Exempt OPM records. Three Office of Personnel Management systems of records apply to Army employees, except for non-appropriated fund employees. These systems, the specific exemptions

determined to be necessary and proper, the records exempted, provisions of the Privacy Act from which exempt, and justification are set forth below: (1) Personnel Investigations Records (OPM/CENTRAL-9). (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958, as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (B) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (C) Records maintained in connection with providing protective services to the President of the United States or other individuals pursuant to Title 18 U.S.C. 3056 may be exempt pursuant to 5 U.S.C. 552a(k)(3). (D) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source.

In addition, DCMA DIBCAC is responsible for leading the Department's contractor cybersecurity risk mitigation efforts. As part of this work, the DIBCAC assesses the defense industrial base companies to ensure they are meeting contractually required cybersecurity standards. The DIBCAC team ensures contractors have the ability to protect controlled unclassified information for government contracts they are awarded. DIBCAC conducts NIST SP 800-171 assessments in support of DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, and DFARS clause 204.204-7020, NIST SP 800-171 DoD Assessment Requirements. The DFARS 204.204-7020 DIBCAC prioritization process is designed to adjust as DoD's cyber priorities evolve based on ongoing threats. DIBCAC analysts collect and analyze data on DoD contractors to include: Mission critical programs, technologies, and infrastructure and the contractors (prime or lower tier) that support DoD capabilities. Cyber threats, vulnerabilities, or incidents. DoD Leadership requests. Regulatory Impact Analysis FAR Subpart 4.19 and DFARS clause 252.204-7012 address safeguarding of FCI and CUI in contractor information systems and prescribe contract clauses requiring protection of FCI and CUI within the supply chain. The FAR and DFARS requirements for safeguarding FCI and CUI predate the CMMC Program by many years, and baseline costs for their implementation are assumed to vary widely based on factors including, but not limited to, company size and complexity of the information systems to be secured. FAR clause 52.204-21 is prescribed at FAR section 4.1903 for use in solicitations and contracts when the contractor or subcontractor at any tier may have FCI residing in or transiting through its information system. This clause requires contractors and subcontractors to apply basic safeguarding requirements and procedures to protect applicable contractor information systems that process, store, or transmit FCI. In addition, DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, is prescribed at DFARS section 204.7304(c) for use by DoD in all solicitations and contracts, including solicitations and contracts using FAR part 12 procedures for the acquisition of commercial items, except for solicitations and contracts solely for the acquisition of commercially available off-the-shelf items. This clause applies when a contractor information system processes, stores, or transmits covered defense information and requires contractors and subcontractors to provide adequate security to safeguard that information when it resides on or transits through a contractor information system, and to report cyber incidents that affect that system or network. The clause states that to provide adequate security, the contractor shall implement, at a minimum, the security requirements in National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 R2,

via email or messaging technologies implemented by the covered entity. At proposed 45 CFR 164.312(b)(4)(i), the Department proposes to require that where a proposed exception applies, a regulated entity would also be required to implement an alternative measure or measures that are reasonable and appropriate compensating controls under proposed 45 CFR 164.312(b)(4)(ii). Compensating controls would be implemented in the place of encryption to protect ePHI from unauthorized access. [745] The Department does not propose to require that compensating controls be limited to technical controls. Rather, a regulated entity should consider the nature of the exception, operating environment, and other appropriate circumstances to determine what controls are reasonable and appropriate and implement compensating controls effective for those circumstances. For example, a regulated entity may use physical access controls, such as physically

limiting access to a device, in combination with other controls to compensate for the absence of encryption. Proposed paragraph (b)(4)(ii)(A) would require that if the regulated entity has determined that an exception applies, it must secure ePHI by implementing reasonable and appropriate compensating controls that are reviewed and approved by the regulated entity's designated Security Official. Because exceptions are a departure from the Security Rule framework, the Department proposes to ensure appropriate focus and review by the Security Official of the controls chosen to compensate for the absence of encryption. With respect to the exception at proposed 45 CFR 164.312(b)(3)(iv)(C), the Department proposes at paragraph (b)(4)(ii)(B) to presume that a regulated entity had implemented reasonable and appropriate compensating controls where the regulated entity has deployed the security measures prescribed and as instructed by the FDA-authorized label for the device. This would include any updates, including patches recommended or required by the manufacturer of the device. The proposed language recognizes that while the device's label may not specifically require deployment of an encryption solution, it may provide for a specific compensating control and the manner in which that control is to be implemented. While not required, a regulated entity would be permitted to implement additional alternative security measures and compensating controls in accordance with best practices and/or its risk analysis. Finally, at proposed paragraph (b)(4)(ii)(C), the Department proposes to require that the regulated entity's Security Official review and document the implementation and effectiveness of the compensating controls during any period in which such compensating controls are in use to continue securing ePHI and relevant electronic (printed page 971)

(9) Conducting FOIA training if it involves issues of DoD policy. (10) Making final determination of requests for expedited processing, fee category, and fee waivers. (m) Records management. FOIA records shall be maintained and disposed of in accordance with the National Archives and Records Administration General Records Schedule and DoD Component records schedules. (n) Relationship between the FOIA and the Privacy Act. Not all requesters are knowledgeable of the appropriate statutory authority to cite when requesting records, nor are all of them aware of appeal procedures. In some instances, requesters may cite either the FOIA or 5 U.S.C. 552a, commonly known as the Privacy Act, or they may cite neither the FOIA nor the Privacy Act but will imply one or both. For these reasons, the below guidelines are provided to ensure requesters receive the greatest access rights under both statutes. Privacy Act requests can be made only by requesters asking for information on themselves contained within a Privacy Act system of records. If the requested information is on another person, the Privacy Act does not apply. These requests shall be processed under the FOIA. (1) Requesters who seek records about themselves contained in a Privacy Act system of records, and who cite or imply the FOIA and/or the Privacy Act, will have their requests processed under the provisions of both the Privacy Act and the FOIA. If the Privacy Act system of records is exempt from the provisions of 5 U.S.C. 552a(d)(1), and if the records, or any portion thereof, are (printed page 71852) exempt under the FOIA, the requester shall be so advised with the appropriate Privacy Act and FOIA exemption(s). Appeals shall be processed under both the FOIA and the Privacy Act. (2) Requesters who seek records about themselves that are not contained in a Privacy Act system of records and who cite or imply the Privacy Act will have their requests processed under the provisions of the FOIA, since the Privacy Act does not apply to these records. Appeals shall be processed under the FOIA. (3) Requesters who seek access to agency records and who cite or imply the FOIA will have their requests and appeals processed under the FOIA. (4) If the record is required to be released under the FOIA, the Privacy Act does not bar its disclosure. Unlike the FOIA, the Privacy Act applies only to U.S. citizens and aliens admitted for permanent residence. (5) Requesters shall be advised in the final response letter which statutory authorities were used, inclusive of appeal rights. (o) Non-responsive information in responsive records.

This guide provides example proof-of-concept solutions demonstrating how available open-source and commercial off-the-shelf (COTS) products could be implemented in discrete-based manufacturing environments to satisfy the requirements in the Cybersecurity Framework (CSF) Manufacturing Profile Low Impact Level. The example proof-of-concept solutions include measured network, device, and operational performance impacts observed during the implementation. Manufacturers should make their own determinations about the breadth of the proof-of-concept solutions they voluntarily implement. Some important factors to consider include: company size, cybersecurity expertise, risk tolerance, and the threat landscape. The CSF Manufacturing Profile can be used as a roadmap for managing cybersecurity risk for manufacturers and is aligned with manufacturing sector goals and industry best practices. The Manufacturing Profile provides a voluntary, risk-based approach for managing cybersecurity activities and cyber risk to manufacturing systems. The Manufacturing Profile is meant

to complement but not replace current cybersecurity standards and industry guidelines that the manufacturer is embracing. This guide describes a proof-of-concept solution for securing manufacturing environments that has only been tested in a lab environment. Manufacturers should make their own determinations about the breadth of the proof-of-concept solutions they voluntarily implement. Some important factors to consider include: company size, cybersecurity expertise, risk tolerance, and the threat landscape. We welcome feedback on its contents and your input. Comments, suggestions, and success stories will improve subsequent versions of this guide. Please contribute your thoughts to CSF_Manufacturing_Profile_Implementation@nist.gov. The example proof-of-concept solutions include measured network, device, and operational performance impacts observed during the implementation.

68 FR 8334 , 8360 (Feb. 20, 2003) (§ 164.314(a) provisions are drawn from and intended to support the analogous privacy protections provided for by 45 CFR 164.504(e) and discussed in the 2000 Privacy Rule.); 78 FR 5566 , 5590 (Jan. 25, 2013) (removed the specific requirements under 45 CFR 164.314 for a memorandum of understanding when both a covered entity and business associate are government entities and referred to the parallel requirements of the Privacy Rule at 45 CFR 164.504(e)(3)). Back to Citation 822. 45 CFR 164.304 (definition of "Security incident"). Back to Citation 823. · See 45 CFR 164.314(a) . Back to Citation 824. ·Where a business associate experiences a security incident that meets the definition of a breach at 45 CFR 164.402 , the business associate must comply with the requirements of the Breach Notification Rule. See 45 CFR part 160 and subparts A and D of 45 CFR part 164 . Specifically, the Breach Notification Rule requires a business associate to report a breach of unsecured PHI to a covered entity without unreasonable delay and in no case later than 60 days from the discovery of the breach. See 45 CFR 164.410(b) . Back to Citation 825. ·Testimony of Andrew Witty, supra note 214 (According to CEO Andrew Witty, intruders attempt to gain access to UnitedHealth Group's electronic information systems every 70 seconds, or more than 450,000 times per year.). Back to Citation 826. 45 CFR 164.308(a)(7)(i) . Back to Citation 827. Id. Back to Citation 828. · See 45 CFR 164.308(a)(7)(i) ; proposed 45 CFR 164.308(a)(13)(i) . Back to Citation 829. 68 FR 8334 , 8351 (Feb. 20, 2003). Back to Citation 830. ··Since 1980, the United States has experienced 265 weather and climate disasters in which the overall damages reached or exceeded US\$1 billion.· Kristie L. Ebi, et al., "Extreme Weather and Climate Change: Population Health and Health System Implications," Annual Review of Public Health (Jan. 2021), <https://pubmed.ncbi.nlm.nih.gov/33406378/>· ; see also "Climate Change Indicators: U.S. and Global Temperature," U.S. Environmental Protection Agency (June 27, 2024) ("2023 was the warmest year on record [. . .] and 2014-2023 was the warmest decade on record since thermometer-based observations began."), <https://www.epa.gov/climate-indicators/climate-change-indicators-us-and-global-temperature> . Back to Citation 831. ··Annual Report to Congress on HIPAA Privacy, Security, and Breach Notification Rule Compliance, For Calendar Year 2022, Office for Civil Rights, U.S. Department of Health and Human Services, p. 8 (2022) (From 2018 to 2022, the number of breaches affecting fewer than 500 individuals increased 1 percent and breaches affecting 500 or more individuals rose 107 percent.), <https://www.hhs.gov/sites/default/files/compliance-report-to-congress-2022.pdf> . Back to Citation 832. ··Unraveling the role of cloud computing in health care system and biomedical sciences, supra

(Comment 41) One comment states that a "retail facility" is defined as a facility that sells food directly to consumers only. Thus, a warehouse store or "cash and carry" store that sells food both to consumers and to commercial accounts would not qualify for this exemption. As the name implies, a "cash and carry" store sells food products to anyone who wishes to buy bulk quantities in cash transactions (e.g., from an individual consumer planning a party or providing for a large family to intermittent supply to restaurants). Such stores typically do not retain detailed records of cash sales. For cash and carry stores that do engage in regular commercial transactions, or which provide credit to commercial customers, ordinary business practices should normally generate records that could be tailored to serve the requirements of the proposed rule. FDA should clarify that, if an entity conducts both exempt and nonexempt activities at the same location, it would be required to retain records only with respect to its nonexempt activities. Under such a clarification, a "cash and carry" store that sells food to individual consumers would not be required to maintain records regarding its retail sales to consumers. The comment requests that the agency adopt and confirm this interpretation.

·Discussion of performance and effectiveness of Federal Risk and Authorization Management Program

(FedRAMP) and cloud computing for the Federal Government, ·Discussion on Executive Order 13556 , Controlled Unclassified Information (CUI), and safeguarding information, ·Panel Discussion of US-CERT · United States Computer Emergency Readiness·Use and Outcomes, ·Discussion on Advancing Information Security in Medical Technologies and Medical Devices, and ·Updates on NIST Computer Security Division. Note that agenda items may change without notice. The final agenda will be posted on the Web site indicated above. Seating will be available for the public and media. Public Participation: The ISPAB agenda will include a period of time, not to exceed thirty minutes, for oral comments from the public (Friday, June 13, 2014, between 9:30 a.m. and 10:00 a.m.). Speakers will be selected on a first-come, first-served basis. Each speaker will be limited to five minutes. Questions from the public will not be considered during this period. Members of the public who are interested in speaking are requested to contact Annie Sokol at the contact information indicated in the FOR FURTHER INFORMATION CONTACT section of this notice. Speakers who wish to expand upon their oral statements, those who had wished to speak but could not be accommodated on the agenda, and those who were unable to attend in person are invited to submit written statements. In addition, written statements are invited and may be submitted to the ISPAB at any time. All written statements should be directed to the ISPAB Secretariat, Information Technology Laboratory, 100 Bureau Drive, Stop 8930, National Institute of Standards and Technology, Gaithersburg, MD 20899-8930. Dated: May 12, 2014. Willie E. May, Associate Director for Laboratory Programs. [FR Doc. 2014-11424 Filed 5-15-14; 8:45 am] BILLING CODE 3510-13-P

3.3.1 | Example 1: Incident Response Roster ... 3.3.1 Example 1: Incident Response Roster A Federal government agency maintains an electronic roster of its computer incident response team members.

documents describing the Department's data governance role because the content is beyond the scope of CMMC requirements. The DoD issued policy guidance to its program managers regarding programmatic indicators to consider when selecting CMMC requirements. Program managers have a vested interest in knowing whether a contractor can comply with these existing requirements to adequately safeguard CUI. The DoD elected not to make any recommended edits to the CMMC Program related to FCI or CUI marking requirements or provide clarifying examples of the differences between Basic CUI and Specified CUI, as these are beyond the scope of this rule. Mishandling of information by the government is beyond the scope of this rule. DCMA DIBCAC processes, stores, and transmits all data on DoD-approved networks. DoD's adherence to NARA's CUI Program policies is beyond the scope of this rule. d. Applicability and Governance of CUI Requirements Comment: In addition, one utilities sector representative submitted a lengthy analysis of data types often generated by electric or other utilities, with regulatory references and rationale for why such data would not likely be subject to DoD's CUI safeguarding requirements or CMMC compliance assessments. Such rationale included the fact that some Government-Private CUI categories, such as DoD Critical Infrastructure Information, require explicit designation in that category which (according to the commenter) has not occurred in the electricity subsector. One contractor requested that CMMC clarify requirements around U.S. persons and foreign dissemination of CUI for both contractors, subcontractors' employees, and contingent workers. Two comments suggested it would be appropriate to reference data governance in §.170.1 and the DoD's role as the data owner of FCI and CUI across the ecosystem. Another comment stated the classification efforts must themselves be audited. Response: The quantity of FCI and CUI a defense contractor possesses, including copies of the same material, is irrelevant to the CMMC assessment required. All copies of FCI or CUI related to the DoD contract must be safeguarded. The CMMC Program is not intended to validate compliance with cybersecurity requirements of non-DoD agencies' contracts. The requirements for sharing of CUI with non-US persons is beyond the scope of this rule. The CMMC program provides a mechanism to assess contractor compliance with applicable security requirements for the safeguarding of FCI or CUI. CMMC program requirements make no change to existing policies for information security requirements implemented by DoD. Policies for CUI and creation of program documentation, to include Security Classification Guides, are separate from this rule. Discussion in this rule regarding DoD programs providing CUI training and the implementation of E.O. 13556 are beyond the scope of this rule.

The tool assumes if there are costs in the first month of the program there will be a Progress Based Payment in the first month of the program. Invoices for PBP's are submitted after the end of the month and thus cannot be paid before about the middle of the 2nd month of the program. This flaw skews the results by assuming the contractor receives payment nearly a month before it is possible. The tool does not provide a mechanism for adjusting calculations based on specific contract requirements when such requirements impact payment lag time either positively or negatively. The

PBP tool is intentionally structured to keep a contractor cash flow negative regardless of how well the contractor performs. Response: The DoD tool takes into account a 22-day lag time between when expenditures occur and when progress payments are made. This accounts for the fact that all expenditures do not occur on the first day of a month or the last day. This is an industry average, and does not accommodate unique lag times by contract. Contractors are supposed to have a positive investment in the effort. FAR 32.1004(b)(3)(ii) states that the contracting officer must ensure that PBPs are not expected to result in an unreasonably low or negative level of contractor investment in the contract. Therefore, contracting officers are still required to use the PBP analysis tool to objectively measure both the benefits and risks of the PBP financing arrangement, and negotiate a mutually beneficial settlement position that reflects adequate consideration to the Government for the improved contractor cash flow. However, the PBP Tool has been revised to remove the cost limitation in accordance with this final rule.

3. Compliance With Generally Accepted Accounting Principles

a. Audited financial statement. Comment: One respondent found the requirement to evidence compliance with Generally Accepted Accounting Principles (GAAP) through audited financial statements burdensome to the contractor. Response: The requirement that the contractors compliance with GAAP must be evidenced through audited financial statements has been removed from the final rule.

b. Make language of rule mirror the statute. Comment: One respondent was concerned that the proposed DFARS rule does not exactly mirror the statute when it requires that the output of a contractor's accounting system shall be in compliance with GAAP, whereas the statute requires a contractor's accounting system to be in compliance (or noncompliance) with GAAP. Response: The wording of the statute is imprecise, because an accounting system cannot be in compliance with GAAP. Compliance with GAAP means that the financial statements are fairly presented, i.e.,

(A) The blanket routine use for Congressional Inquiries (see Appendix C, section D) applies to all systems. When an individual requests the assistance of the Congressional member, the blanket routine use permits the disclosure of records pertaining to the individual without the express written consent of the individual. (B) If necessary, accept constituent letters requesting a member of Congress to investigate a matter pertaining to the individual as written authorization to provide access to the records to the congressional member or his or her staff. (C) When a Congressional inquiry indicates that the request is being made on the basis of a request from the individual to whom the record pertains, consent can be inferred even if the constituent request is not provided the Component. The verbal statement by a Congressional staff member is acceptable to establish that a request has been received by the Member of Congress from the person to whom the records pertain. (D) If the constituent inquiry is being made on behalf of someone other than the individual to whom the record pertains, the Member of Congress shall be provided only that information releasable under DoD 5400.7-R. Advise the Congressional member that the written consent of the individual to whom the record pertains is required before any additional information may be disclosed. Do not contact individuals to obtain their consents for release to Congressional members unless a Congressional office specifically requests that this be done. (E) Nothing in paragraph (i)(2)(ii)(A) of this section prohibits a Component, when appropriate, from providing the record directly to the individual and notifying the Congressional office that this has been done without providing the record to the Congressional member. (3) See paragraph (e) of § 310.20 for the policy on assessing fees for Members of Congress. (4) Make a disclosure accounting each time a record is disclosed to either House of Congress, to any committee, joint committee, or subcommittee of Congress, or to any congressional member. (j) Disclosures to the General Accountability Office. Records may be disclosed to the Comptroller General, or any of his authorized representatives, in the course of the performance of the duties of the General Accountability Office. (k) Disclosures under court orders. (1) Records may be disclosed without the consent of the person to whom they pertain under a court order signed by a judge of a court of competent jurisdiction. (2) When a record is disclosed under this provision, make reasonable efforts to notify the individual to whom the record pertains, if the legal process is a matter of public record. (3) If the process is not a matter of public record at the time it is issued, seek information as to when the process is to be made public and make reasonable efforts to notify the individual at that time.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and

privacy of other than national security-related information in federal information systems. Smart inverters used in home and small business solar power systems are examples of IoT devices. IR 8259, Foundational Cybersecurity Activities for IoT Device Manufacturers [7], describes its guidance as applying to devices that 'have at least one transducer (sensor or actuator) for interacting directly with the physical world and at least one network interface (e.g., Ethernet, Wi-Fi, Bluetooth, Long-Term Evolution [LTE], Zigbee, Ultra-Wideband [UWB]) for interfacing with the digital world.' Smart inverters sense the state of the power grid, provide power to the grid, and communicate with owners and grid operators through communications interfaces that satisfy this description. Emerging inverter controllers may also require the autonomous exchange of information between inverters. Hence, the general cybersecurity guidance presented in IR 8259 [7] is applicable to smart inverters.

(n) The Surgeon General/Commander, U.S. Army Medical Command, is authorized to act on requests for medical research and development records, and the medical records of active duty military personnel, dependents, and persons given physical examination or treatment at DA medical facilities, to include alcohol and drug treatment/test records. (o) The Chief of Chaplains is authorized to act on requests for records involving ecclesiastical relationships, rites performed by DA chaplains, and nonprivileged communications relating to clergy and active duty chaplains' military personnel files. (p) The Judge Advocate General is authorized to act on requests for records relating to claims, courts-martial, legal services, administrative (q) The Chief, National Guard Bureau, is authorized to act on requests for all personnel and medical records of retired, separated, discharged, deceased, and active Army National Guard military personnel, including technician personnel, unless such records clearly fall within another Denial Authority's responsibility. This authority includes, but is not limited to, National Guard organization and training files; plans, operations, and readiness files, policy files, historical files, files relating to National Guard military support, drug interdiction, and civil disturbances; construction, civil works, and ecology records dealing with armories, facilities within the States, ranges, etc.; Equal Opportunity investigative records; aviation program records and financial records dealing with personnel, operation and maintenance, and equipment budgets. (r) The Chief, Army Reserve and Commander, U.S. Army Reserve Command are authorized to act on requests for all (printed page 46067) personnel and medical records of retired, separated, discharged, deceased, and reserve component military personnel, and all U.S. Army Reserve (USAR) records, unless such records clearly fall within another Denial Authority's responsibility. Records under the responsibility of the Chief, Army Reserve and the Commander, U.S. Army Reserve Command include records relating to USAR plans, policies, and operations; changes in the organizational status of USAR units; mobilization and demobilization policies, active duty tours, and the Individual Mobilization Augmentation program; and all other Office of the Chief, Army Reserve (OCAR) records and Headquarters, U.S. Army Reserve Command records. (s) The Commander, United States Army Materiel Command (AMC) is authorized to act on requests for the records of AMC headquarters and to subordinate commands, units, and activities that relate to procurement, logistics, research and development, and supply and maintenance operations.

; In 2016, PHI was valued at 50 times the worth of financial information on the black market. Diane Doebele Koch, 'Is the HIPAA Security Rule Enough to Protect Electronic Personal Health Information (PHI) in the Cyber Age?', *Journal of Health Care Finance*, p. 22 (Spring 2016) (citing Beth Kutscher, 'Healthcare underspends on Cybersecurity as attacks accelerate', *Modern Healthcare* (Mar. 3, 2016), <https://www.modernhealthcare.com/article/20160303/NEWS/160309922/healthcare-underspends-on-cybersecurity-as-attacks-accelerate> .); 'New Dangers in the New World: Cyber Attacks in the Healthcare Industry', *supra* note 135, p. 3 ('[. . .] stolen medical data sells for 10-20 times more than credit card data.'). Back to Citation 208. 'Gilbert Munoz-Cornejo, et al., 'Analyzing the urban-rural divide: the role of location, time, and breach characteristics in U.S. hospital security incidents, 2012-2021', *Discover Health Systems* (June 17, 2024), <https://link.springer.com/article/10.1007/s44250-024-00105-6#:~:text=Specifically%2C%20our%20study%20shows%20that,trend%20of%20breaches%20over%20time> . Back to Citation 209. 'Lynne Coventry, et al., 'Cybersecurity in healthcare: A narrative review of trends, threats and ways forward', *Maturitas*, p. 46 (July 2018), [https://www.maturitas.org/article/S0378-5122\(18\)30165-8/abstract](https://www.maturitas.org/article/S0378-5122(18)30165-8/abstract) . Back to Citation 210. Id. Back to Citation 211. 'See 'Breach Portal: Notice to the Secretary of HHS Breach of Unsecured Protected Health Information', *supra* note 10. Back to Citation 212. Id. Back to Citation 213. 'Annual Report to Congress on Breaches of Unsecured Protected Health Information: For Calendar Year 2022', *Office for Civil Rights, U.S. Department of Health and Human Services*, p. 8-9 (2022), <https://www.hhs.gov/sites/default/files/breach-report-to-congress-2022.pdf> . Back

to Citation 214. Change Healthcare is a health care clearinghouse and a subsidiary of UnitedHealth Group, <https://www.changehealthcare.com/>. On the morning of Feb. 21, 2024, Optum (another subsidiary of UnitedHealth Group) reported that it was experiencing enterprise-wide connectivity issues. By that afternoon, the announcement changed to a network interruption related to a cyber security issue and explained that [o]nce [Change Healthcare] became aware of the outside threat, in the interest of protecting our partners and patients, we took immediate action to disconnect our systems to prevent further impact. See Optum Solution Status, Optum, Inc., UnitedHealth Group, <https://solution-status.optum.com/incidents/hqpjz25fn3n7> (last accessed on July 16, 2024). On Mar. 13, 2024, the Department announced that it would be initiating an investigation into the incident. See Letter from OCR Director Melanie Fontes Rainer to Colleagues (Mar. 13, 2024), <https://www.hhs.gov/sites/default/files/cyberattack-change-healthcare.pdf>.

3.5.5 | Delegation ... 3.5.5 Delegation Proper enforcement of data resource policies is dependent on the enforcement of attribute administrative policies.

§ 170.10 CMMC Assessor and Instructor Certification Organization (CAICO). (a) Roles and responsibilities. The CAICO is responsible for training, testing, authorizing, certifying, and recertifying CMMC assessors, instructors, and related professionals. Only the CAICO may make decisions relating to examination certifications, including the granting, maintaining, recertifying, expanding, and reducing the scope of certification, and suspending or withdrawing certification in accordance with current ISO/IEC 17024:2012(E) (incorporated by reference, see § 170.2). At any given point in time, there will be only one CAICO for the DoD CMMC Program. (b) Requirements. The CAICO shall: (1) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17) ; and achieve and maintain ISO/IEC 17024(E) accreditation within 12 months of December 16, 2024. (2) Provide all documentation and records in English. (3) Train, test, and designate PIs in accordance with the requirements of this section. Train, test, certify, and recertify CCPs, CCAs, and CCIs in accordance with the requirements of this section. (4) Ensure the instructor and assessor certification examinations are certified under ISO/IEC 17024:2012(E) (incorporated by reference, see § 170.2), by a recognized US-based accreditor who is not a member of the CMMC Accreditation Body. The US-based accreditor must be a signatory to International Laboratory Accreditation Cooperation (ILAC) or relevant International Accreditation Forum (IAF) Mutual Recognition Arrangement (MRA) and must operate in accordance with ISO/IEC 17011:2017(E) (incorporated by reference, see § 170.2). (5) Establish quality control policies and procedures for the generation of training products, instruction, and testing materials. (6) Oversee development, administration, and management pertaining to the quality of training and examination materials for CMMC assessor and instructor certification and recertification. (7) Establish and publish an authorization and certification appeals process to receive, evaluate, and make decisions on complaints and appeals in accordance with ISO/IEC 17024:2012(E) (incorporated by reference, see § 170.2). (8) Address all appeals arising from the CCA, CCI, and CCP authorizations and certifications process through use of internal processes in accordance with ISO/IEC 17024:2012(E) (incorporated by reference, see § 170.2). (9) Maintain records for a period of six (6) years of all procedures, processes, and actions related to fulfillment of the requirements set forth in this section and provide the Accreditation Body access to those records. (10) Provide the Accreditation Body information about the authorization and accreditation status of assessors, instructors, training community, and publishing partners. (11) Ensure separation of duties between individuals involved in testing activities, training activities, and certification activities. (12) Safeguard and require any CAICO training support service providers, as applicable, to safeguard the confidentiality of applicant, candidate, and certificate-holder information and ensure the overall security of the certification process. (13) Ensure that all PII is encrypted and protected in all CAICO information systems and databases and those of any CAICO training support service providers. (14) Ensure the security of assessor and instructor examinations and the fair and credible administration of examinations. (15) Neither disclose nor allow any CAICO training support service providers, as applicable, to disclose CMMC data or metrics related to authorization or certification activities to any entity other than the Accreditation Body and DoD, except as required by law. (16) Require retraining and redesignation of PIs upon significant change to DoD's CMMC Program requirements. Require retraining and recertification of CCPs, CCAs, and CCIs upon significant change to DoD's CMMC Program requirements, as determined by the DoD or the CAICO. (17) Require CMMC Ecosystem members to report to the CAICO within 30 days of convictions, guilty pleas, or no contest pleas to crimes of fraud, larceny, embezzlement,

misappropriation of funds, misrepresentation, perjury, false swearing, conspiracy to conceal, or a similar offense in any legal proceeding, civil or criminal, whether or not in connection with activities that relate to carrying out their role in the CMMC Ecosystem.

blication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations. - Federal agencies responsible for managing and protecting CUI - Nonfederal organizations responsible for protecting CUI - Individuals with system development life cycle responsibilities (e.g., program managers, mission/business owners, information owners/stewards, system designers and developers, system/security engineers, systems integrators) - Individuals with acquisition or procurement responsibilities (e.g., contracting officers) - Individuals with system, security, or risk management and oversight responsibilities (e.g., authorizing officials, chief information officers, chief information security officers, system owners, information security managers) - Individuals with security assessment and monitoring responsibilities (e.g., auditors, system evaluators, assessors, analysts, independent verifiers and validators)

(B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (23) System identifier and name. A0351-17a USMA, U.S. Military Academy Candidate Files. (i) Exemption. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (B) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6) , if the disclosure would compromise the objectivity or fairness of the test or examination process. (C) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7) , but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (D) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(5) , (k)(6) or (k)(7) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) , (k)(6) and (k)(7). (iii) Reasons. (A) From subsections (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement.

. This provision is followed by paragraph (d), which explains that regulated entities are required to implement a specific implementation specification if described as 'required.' If the implementation specification is described as 'addressable,' regulated entities are required to implement the implementation specification if it is reasonable and appropriate to do so; or, if it is not reasonable and appropriate, document why and implement an equivalent alternative measure. Finally, the maintenance provision at 45 CFR 164.306(e) requires regulated entities to review and modify security measures implemented under the Security Rule as needed to continue providing reasonable and appropriate protection of ePHI. It also requires regulated entities to update documentation of such security measures in accordance with the requirements for documentation at 45 CFR 164.316(b)(2)(iii) . 2. Issues To Address We believe that we can improve consistency in language between this section and other Security Rule provisions and better align this section with

statutory terms and intent. For example, we are concerned that regulated entities are misinterpreting 45 CFR 164.306(a) to apply the requirements of the Security Rule to only some ePHI, rather than all ePHI. This interpretation could lead to inadequate protection of ePHI and relevant electronic information systems. [412] We also believe that consistency in language facilitates clear understanding and less ambiguity about how regulated entities must apply Security Rule standards. Flexibility and scalability are among the Security Rule's defining characteristics, and we intend to preserve those elements to the extent possible. However, we believe that in this era of increased reliance on technology, more sophisticated cyber capabilities, and increasing cyberattacks, it is critical for regulated entities to implement and deploy strong security measures to protect ePHI and related information systems. We are concerned that regulated entities have focused their attention primarily on the cost of security measures, rather than considering the reasonableness and appropriateness of security measures in the context of all of the listed factors, including the probability and criticality of potential risks to ePHI. [413] Further, the Department believes that providing additional clarity would improve the ability of regulated entities to evaluate security measures for the protection of ePHI and the ability of a security measure to facilitate a regulated entity's recovery from emergencies and to support continued operations. With these proposed modifications, the Department seeks to ensure that regulated entities' reliance on the Security Rule's flexibility and scalability does not come at the expense of adequate security. The current regulation's framework in 45 CFR 164.306(b) lacks any express factor that would require an evaluation of the effectiveness of the security measures in supporting the resiliency of the regulated entity.

3.1.1 Achievement of Goals and Objectives ... 3.1.1 Achievement of Goals and Objectives Cyber resiliency techniques and associated implementation approaches are employed to achieve mission or business objectives. 3.1.1.

(iii) Inform the requester of the right to file a ·Statement of Disagreement· with the Board's action and to seek judicial review of the Army's refusal to amend. A ·Statement of Disagreement· must be received by the system manager within 120 days and it will be made an integral part of the pertinent record. Anyone who may have access to, use of, or need to disclose information from the record will be aware that the record was disputed. The disclosing authority may include a brief summary of the Board's reasons for not amending the disputed record. (7) It is inappropriate for the Privacy Act Review Board to consider any record which is exempt from the amendment provision of the Privacy Act. § 505.7 Disclosure of personal information to other agencies and third parties. (a) Disclosing records to third parties. (1) DA is prohibited from disclosing a record from a Privacy Act system of records to any person or agency without the prior written consent of the subject of the record, except when· (i) Pursuant to the twelve Privacy Act exceptions. The twelve exceptions to the ·no disclosure without consent· rule are those exceptions which permit the release of personal information without the individual's/subject's consent (See appendix C of this part). (ii) The FOIA requires the release of the record. One of the twelve exceptions to Privacy Act is the FOIA Exception. If the FOIA requires the release of information, the information must be released. The Privacy Act can not prevent release to a third party if the FOIA requires release. However, information must not be discretionarily released under the FOIA if the information is subject to the Privacy Act's ·no disclosure without consent· rule. (iii) A routine use applies. Another major exception to the ·no disclosure without consent· rule is the routine use exception. The Privacy Act allows federal agencies to publish routine use exceptions to the Privacy Act. Some routine uses are Army specific, DOD specific, and Government-wide. Routine uses exceptions are listed in the Privacy Act system of records notice(s) applicable to the Privacy Act records in question. The Army and other agencies' system of records notices may be accessed at the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy> . (2) The approved twelve exceptions to the Privacy Act ·no disclosure without consent· rule are listed at appendix C of this part. (b) Disclosing records to other DOD components and to Federal agencies outside the DOD. (1) The twelve Privacy Act exceptions referred to in appendix C of this part are available to other DOD components and to Federal agencies outside the DOD as exceptions to the Privacy Act's ·no disclosure without consent· rule, with the exception of the FOIA exception. The FOIA is not an appropriate mechanism for providing information to other DOD components and to Federal agencies outside the DOD.

specification for unique user identification requires a regulated entity to assign unique identifiers to users to facilitate the identification of specific users of an information system. [666] By assigning a unique identifier to each user, a regulated entity can track the specific

activity of that user when they are logged into an information system and hold the user accountable for functions they perform in the information system when they access that system. Under the implementation specification for emergency access procedures, a regulated entity is required to establish procedures, such as documented operational practices and instructions to workforce members, for obtaining access to necessary ePHI during an emergency and to implement such procedures as needed. [667] In accordance with this implementation specification, a regulated entity must identify the types of situations in which its normal procedures for accessing an information system or application that contains ePHI may not work and establish procedures for obtaining access in those situations. [668] These procedures must be established prior to an emergency to instruct workforce members on possible ways to gain access to needed ePHI where, for example, the electrical system has been severely damaged or rendered inoperative, or where a software update fails and prevents the regulated entity from accessing ePHI in its EHR. The implementation specification for automatic logoff associated with the standard for access control addresses the need for a regulated entity to, when reasonable and appropriate, implement electronic procedures that terminate an electronic session after a period of inactivity. [669] Automatic logoff is an effective way to prevent unauthorized users from accessing ePHI on a workstation when it is left unattended for a period of time. [670] While many applications have configuration settings that automatically log a user out of the system after a period of inactivity, some systems have more limited capabilities and may activate a screen saver that is password protected. [671] The implementation specification under the standard for access control addresses encryption and decryption and requires regulated entities, when it is reasonable and appropriate, to implement a mechanism to encrypt and decrypt ePHI. [672] Encrypting data, including ePHI, reduces the likelihood that anyone other than the party that has the key to the encryption algorithm would be able to decrypt (i.e., translate) the data and convert it into plain, comprehensible text. [673] The standard for audit controls requires a regulated entity to implement hardware, software, and/or procedural mechanisms that record and examine activity in electronic information systems that contain or use ePHI. Most electronic information systems provide some level of audit controls with a reporting method, such as audit reports. [674]

This scoring methodology is designed to provide a measurement of an OSA's implementation status of the NIST SP 800-171 Rev 2 security requirements (incorporated by reference elsewhere in this part, see §.170.2) and the specified NIST SP 800-172 security requirements (incorporated by reference elsewhere in this part, see §.170.2). The CMMC Scoring Methodology is designed to credit partial implementation only in limited cases (e.g., multi-factor authentication, CMMC Level 2 security requirement IA.L2-3.5.3, a Derived Security Requirement). (b) Assessment findings. Each security requirement assessed under the CMMC Scoring Methodology must result in one of three possible assessment findings, as follows: (1) MET. All applicable objectives for the security requirement are satisfied based on evidence. All evidence must be in final form and not draft. Unacceptable forms of evidence include working papers, drafts, and unofficial or unapproved policies. (2) NOT MET. One or more applicable objectives for the security requirement is not satisfied. During an assessment, for each security requirement objective marked NOT MET, the assessor will document why the evidence does not conform. (3) NOT APPLICABLE (N/A). A security requirement and/or objective does not apply at the time of the CMMC (printed page 89137) assessment. For example, CMMC security requirement SC.L1-3.13.5 -Public-Access System Separation- might be N/A if there are no publicly accessible systems within the CMMC Assessment Scope. During an assessment, an assessment objective assessed as N/A is equivalent to the same assessment objective being assessed as MET. (c) Scoring. At each CMMC Level, security requirements are scored as follows: (1) CMMC Level 1. All CMMC Level 1 security requirements must be fully implemented to be considered MET. No POA&M is permitted for CMMC Level 1, and self-assessment results are scored as MET or NOT MET in their entirety; therefore, no score is calculated, and no scoring methodology is needed. (2) CMMC Level 2 Scoring Methodology. The maximum score achievable for a CMMC Level 2 assessment is equal to the total number of CMMC Level 2 security requirements. If all CMMC Level 2 security requirement objectives are MET, OSAs are awarded the maximum score. For each requirement objective NOT MET, the associated value of the security requirement is subtracted from the maximum score, which may result in a negative score. (i) Procedures (A) Scoring methodology for CMMC Level 2 assessment is based on all CMMC Level 2 security requirement objectives, including those NOT MET. (B) In the CMMC Level 2 Scoring Methodology, each security requirement has a value (e.g., 1, 3 or 5). (1) For NIST SP 800-171 Rev 2 Basic and Derived Security Requirements that, if not implemented, could lead to significant exploitation of the network, or exfiltration of CUI, 5 points are subtracted from the maximum score. The Basic and Derived security requirements with a value of 5 points include: (i

Except requests that are for a commercial use, the Component may not charge for the first 2 hours of search time or for the first 100 pages of reproduction. However, a requester may not file multiple requests at the same time, each seeking portions of a document or documents, solely in order to avoid payment of fees. When a Component reasonably believes that a requester or, on rare occasions, a group of requesters acting in concert, is attempting to break a request down into a series of requests for the purpose of avoiding the assessment of fees, the Component may aggregate any such requests and charge accordingly. One element to be considered in determining whether this belief would be reasonable is the time period in which the requests have occurred. For example, it would be reasonable to presume that multiple requests of this type made within a 30 day period had been made to avoid fees. For requests made over a longer period however, such a presumption becomes harder to sustain and Components should have a solid basis for determining that aggregation is warranted in such cases. Components are cautioned that before aggregating requests from more than one requester, they must have a concrete basis on which to conclude that the requesters are acting in concert and are acting specifically to avoid payment of fees. In no case may Components aggregate multiple requests on unrelated subjects from one requester. (f) Effect of the Debt Collection Act of 1982 (Pub. L. 97-365). The Debt Collection Act of 1982 provides for a minimum annual rate of interest to be charged on overdue debts owed the Federal Government. Components may levy this interest penalty for any fees that remain outstanding 30 calendar days from the date of billing (the first demand notice) to the requester of the amount owed. The interest rate shall be as prescribed in DoD 7000.14-R, Volume 11A. Components should verify the current interest rate with respective Finance and Accounting Offices. After one demand letter has been sent, and 30 calendar days have lapsed with no payment, Components may submit the debt to respective Finance and Accounting Offices for collection pursuant to the Debt Collection Act of 1982. (g) Computation of fees. The fee schedule in this subchapter shall be used to compute the assessable fees based upon the time actually spent on the search, review (in the case of commercial requesters) and duplication costs associated with processing a given FOIA request. Neither time-based nor dollar-based minimum charges for search, review and duplication are authorized. The appropriate fee category of the requester shall be determined before computing fees. All time computations will be to the nearest 15 minutes or quarter hour. (h) Refunds. In the event a Component discovers it has overcharged a requester or a requester has overpaid, the Component shall promptly refund the charge to the requester by reimbursement methods that are agreeable to the requester and the Component.

HIPAA Security Rule section 164.308 (Administrative Safeguards) addresses information access management. Covered entities and business associates must implement appropriate safeguards to protect electronic protected health information (ePHI). For information access management, organizations should:

1. Establish and document policies specific to information access management
2. Implement technical and procedural controls
3. Train workforce members on their responsibilities
4. Conduct periodic risk assessments addressing information access management
5. Maintain documentation of compliance efforts

Under 45 CFR 164.308, this is a administrative safeguards requirement that applies to all covered entities and business associates that create, receive, maintain, or transmit ePHI.

3.3.4 | Management APIs, Management Software, and In-Band Management ... 3.3.4 Management APIs, Management Software, and In-Band Management Storage infrastructure components expose management software User Interfaces (UI), APIs, and other in-band or out-of-band management protocols for administering the devices and managing data storage.

(i) When line security is not available, installation will require two independent means of transmission of the alarm signal from the alarmed area to the monitoring station. (ii) Alarm installation provides a level of protection, e.g. UL's Extent 5, based on patrolling employees and CSA approval of security-in-depth. (iii) Where law enforcement personnel are the primary alarm response. Under those circumstances, the contractor must obtain written assurance from the police department regarding the ability to respond to alarms in the required response time. (iv) Alarm signal transmission is over computer-controlled data-networks (e.g., internet, intranet). The CSA will provide specific acceptance criteria (e.g., encryption requirements) for alarms monitored over data networks. (v) Alarm investigator response time exceeds the parameters outlined in paragraphs (c)(1) through (c)(3) in this section as applicable. (5) Certification of compliance. Evidence of compliance with the requirements of this section will consist of a valid (current) certification by an approved NRTL for the appropriate category of service. This certificate: (i)

Will have been issued to the protected facility by the NRTL, through the alarm service company.

(ii) Serves as evidence that the alarm service company that did the installation is: (A) Listed as furnishing security systems of the category indicated. (B) Authorized to issue the certificate of installation as representation that the equipment is in compliance with requirements established by NRTL for the class of alarm system. (C) Subject to the NRTL inspection program whereby periodic inspections are made of representative alarm installations by NRTL personnel to verify the correctness of certification practices. (6) Exceptional cases. (i) If the requirements in paragraphs (d)(1) through (d)(5) in this section cannot be met, the contractor may request CSA approval for an alarm system meeting one of these conditions, which will be documented on the alarm system description form: (A) Monitored by a central control station but responded to by a local (municipal, county, state) law enforcement organization. (B) Connected by direct wire to alarm receiving equipment located in a local (municipal, county, State) police station or public emergency service dispatch center. This alarm system is activated and deactivated by employees of the contractor, but the alarm is monitored and responded to by personnel of the monitoring police or emergency service dispatch organization. Personnel monitoring alarm signals at police stations or dispatch centers do not require PCLs. Police department response systems may be requested only when: (1) The contractor facility is located in an area where central control station services are not available with line security or proprietary security force personnel, or a contractually-dispatched response to an alarm signal cannot be achieved within the time limits required by the CSA. (2

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analysis to advance the development and productive use of information technology. ITL's responsibilities include the development of technical, physical, administrative, and management standards and guidelines for the cost-effective security and privacy of sensitive unclassified information in Federal computer systems. This Special Publication 800-series reports on ITL's research, guidance, and outreach efforts in computer security and its collaborative activities with industry, government, and academic organizations. In today's computing environment, there are many threats to the confidentiality of information stored on end user devices, such as personal computers, consumer devices (e.g., personal digital assistant, smart phone), and removable storage media (e.g., universal serial bus [USB] flash drive, memory card, external hard drive, writeable CD or DVD). Some threats are unintentional, such as human error, while others are intentional. Intentional threats are posed by people with many different motivations, including causing mischief and disruption and committing identity theft and other fraud. A common threat against end user devices is device loss or theft. Someone with physical access to a device has many options for attempting to view or copy the information stored on the device. Another concern is insider attacks, such as an employee attempting to access sensitive information stored on another employee's device.

Level 1 or 2); costs to prepare for and undergo Level 2 certification assessment; and costs required to implement the Level 3 security requirements and for preparing to undergo DCMA DIBCAC assessment (Level 3). CMMC Level 3 certification assessments against the NIST SP 800-172 Feb2021 baseline are performed free of cost by DoD assessors, which reduces the overall cost of achieving CMMC Status of Level 3 (DIBCAC). Notably, certification is never required for CMMC Level 1, and the requirement can be satisfied through self-assessment. When CMMC Level 2 requirements apply, they may be met via self-assessment, or a certification assessment conducted by a C3PAO, depending on the specific CMMC requirement cited in the solicitation or resulting contract. When the CMMC Program requirements are effective, solicitations for DoD contracts that will involve the processing, storing, or transmitting of FCI or CUI on any non-Federal system, notwithstanding the size or configuration of the non-Federal system, will specify the required CMMC Level (1, 2 or 3) and assessment type (self-assessment or certification assessment). An assumption for the cost estimates is that Non-Small Entities have a full-time team of cybersecurity professionals on staff while Small Entities do not. The assumptions, explained in the regulatory impact analysis, reflect Small Entities will likely obtain support from External Service Providers and have a staff member submit affirmations and SPRS scores for self-assessments. All (printed page 83197) these costs, except the open market cost of a C3PAO, are directly controllable by the organization seeking assessment. The CMMC rule does not make any change to cost allowability as defined in FAR 31.201-2 Determining Allowability. The DoD declined to modify the estimates, which are intended to be representative and to inform rulemaking. The cost estimates represent average derived estimates based on internal expertise and public

feedback in accordance with OMB Circular A-4 and represent average costs for companies to comply with the CMMC requirements. This rule does not provide the cost analysis for all actions, personnel, and security measures required to protect CUI information, data, systems, and technical products through the life cycle of the work and data generated. The size and complexity of the network within scope of the assessment impacts the costs as well. As required by rulemaking guidance, the DoD provided cost estimates and impact analyses. An analysis of profit margins is not required. Additionally, this rule and the required cost analysis and resulting cost estimates were reviewed by DoD cost analysts and OMB economists for realism and completeness.

NIST SP 800-171 and NIST SP 800-53 are related but serve different audiences: **NIST SP 800-53 Rev 5**: - Comprehensive catalog of ~1,000+ security controls - Designed for federal information systems - Organized into 20 control families - Used as the basis for FedRAMP - Includes controls at Low, Moderate, and High baselines **NIST SP 800-171 Rev 3**: - 97 security requirements (derived from 800-53) - Designed for non-federal systems handling CUI - Organized into 17 families - Used as the basis for CMMC Level 2 - Tailored specifically for the defense industrial base SP 800-171 is essentially a subset of SP 800-53 tailored for contractors. Appendix D of SP 800-171 provides the direct mapping between the two standards.

(iv) When access is requested by mail, identity verification may consist of the individual providing certain minimum identifying data, such as full name, date and place of birth, or such other personal information necessary to locate the record sought and information that is ordinarily only known to the individual. If the information sought is of a sensitive nature, additional identifying data may be required. An unsworn declaration under penalty of perjury (28 U.S.C. 1746 , ·Unsworn Declaration under Penalty of Perjury·) or notarized signatures are acceptable as a means of proving the identity of the individual. (printed page 18767) (A) If an unsworn declaration is executed within the United States, its territories, possessions, or commonwealths, it shall read ·I declare (or certify, verify, or state) under penalty of perjury that the foregoing is true and correct. Executed on (date). (Signature)· (B) If an unsworn declaration is executed outside the United States, it shall read ·I declare (or certify, verify, or state) under penalty of perjury under the laws of the United States of America that the foregoing is true and correct. Executed on (date). (Signature)· (v) If an individual wishes to be accompanied by a third party when seeking access to his or her records or to have the records released directly to a third party, the individual may be required to furnish a signed access authorization granting the third-party access. (vi) An individual shall not be refused access to his or her record solely because he or she refuses to divulge his or her SSN unless the SSN is the only method by which retrieval can be made. (See §310.15(b).) (vii) The individual is not required to explain or justify his or her need for access to any record under this part. (viii) Only a denial authority may deny access and the denial must be in writing and contain the information required by 310.18. (d) Granting individual access to records. (1) Grant the individual access to the original record or an exact copy of the original record without any changes or deletions, except when deletions have been made in accordance with paragraph (e) of this Section. For the purpose of granting access, a record that has been amended under §310.19(b) is considered to be the original. See paragraph (e) of this Section for the policy regarding the use of summaries and extracts. (2) Provide exact copies of the record when furnishing the individual copies of records under this part. (3) Explain in terms understood by the requestor any record or portion of a record that is not clear. (e) Illegible, incomplete, or partially exempt records. (1) Do not deny an individual access to a record or a copy of a record solely because the physical condition or format of the record does not make it readily available (for example, deteriorated state or on magnetic tape). Either prepare an extract or recopy the document exactly.

To withhold information under this privilege, the information must be both deliberative and predecisional, and part of the decision-making process. Deliberative means the information is internal advice, recommendations, or subjective evaluations, as contrasted with factual matters, that are reflected in records relied upon in the decision-making process of an agency, whether within or among agencies. Predecisional means the information was created before the decision maker reached a final decision. Factual information cannot be withheld from a requester under Exemption 5 except under one of two circumstances. The first circumstance is when the author of a document selects specific facts out of a larger group of facts and this very act is deliberative in nature. This information qualifies for withholding because its release would reveal the author's internal thought processes. The second circumstance exists when the factual information is so inextricably

connected to the deliberative material that its disclosure would expose or cause harm to the agency's deliberations. A direction or order from a superior to a subordinate generally does not qualify as a deliberative process document if it constitutes policy guidance or a decision. However, correspondence from a superior to a subordinate may qualify if it constitutes a discussion of preliminary matters or a request for information or advice that would be relied upon in the decision-making process. An agency's final decision cannot be withheld under the privilege unless it becomes part of another, higher-level decision-making process (such as the agency budgetary process). The deliberative process privilege is temporal in nature because once the final agency decision is made the privilege cannot be used to withhold the final decision or any post-decisional documents related to the decision. Examples of deliberative process documents include: (A) Staff papers, to include after-action reports, inspection reports, lessons learned, and situation reports containing staff evaluations, advice, opinions, or suggestions. (B) Advice, suggestions, or evaluations prepared on behalf of the Department of Defense by individual consultants or by boards, committees, councils, groups, panels, conferences, commissions, task forces, or other similar groups that are formed for the purpose of obtaining advice and recommendations. (C) Evaluations by DoD Component personnel of contractors and their products. (D) Information of a speculative, tentative, or evaluative nature, or such matters as proposed plans to procure, lease, or otherwise acquire and dispose of materials, real estate, facilities or functions, when such information would provide undue or unfair competitive advantage to private personal interests or would impede legitimate Government functions.

A CMMC Certified Instructor (CCI) teaches CCP, CCA, and CCI candidates and performs CMMC instructional duties. Candidate CCIs are certified by the CAICO after successful completion of the CCI training and testing requirements. A CCI is required to obtain and maintain assessor and instructor certifications from the CAICO in accordance with the requirements set forth in § 170.10 and in paragraph (c) of this section. A CCI with a valid CCP certification may instruct CCP candidates, while a CCI with a valid CCA certification may instruct CCP, CCA, and CCI candidates. Certifications are valid for 3 years from the date of issuance. CCIs are required to meet requirements in paragraph (c) of this section. (c) Requirements. CMMC Instructors shall: (1) Obtain and maintain instructor designation or certification, as appropriate, from the CAICO in accordance with the requirements set forth in § 170.10. (2) Obtain and maintain CCP or CCA certification to deliver CCP training. (3) Obtain and maintain a CCA certification to deliver CCA training. (4) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17). (5) Provide all documentation and records in English. (6) Provide the Accreditation Body and the CAICO annually with accurate information detailing their qualifications, training experience, professional affiliations, and certifications, and, upon reasonable request, submit documentation verifying this information. (7) Not provide CMMC consulting services while serving as a CMMC instructor; however, subject to the Code of Professional Conduct and Conflict of Interest policies, can serve on an assessment team. (8) Not participate in the development of exam objectives and/or exam content or act as an exam proctor while at the same time serving as a CCI. (9) Keep confidential all information obtained or created during the performance of CMMC training activities, including trainee records, except as required by law. (10) Not disclose any CMMC-related data or metrics that is PII, FCI, or CUI to anyone without prior coordination with and approval from DoD. (11) Notify the Accreditation Body or the CAICO if required by law or authorized by contractual commitments to release confidential information. (12) Not share with anyone any CMMC training-related information not previously publicly disclosed. § 170.13 CMMC Certified Professional (CCP). (a) Roles and responsibilities. A CMMC Certified Professional (CCP) completes rigorous training on CMMC and the assessment process to provide advice, consulting, and recommendations to their OSA clients. Candidate CCPs are certified by the CAICO after successful completion of the CCP training and testing requirements set forth in paragraph (b) of this section. CCPs are eligible to become CMMC Certified Assessors and can participate as a CCP on Level 2 certification assessments with CCA oversight where the CCA makes all final determinations. (b) Requirements. CCPs shall:

provided other recommended edits to the POA&M section, including addition of terms of art such as ·assessment-related· and ·non-assessment-related·, and deletion of the words ·as applicable·.

Response: The CMMC Program allows the use of POA&Ms. Section 170.21 delineates the requirements that may be addressed as part of an assessment with a POA&M, that must be closed out by a POA&M closeout assessment within 180 days of the initial assessment to achieve the assessment requirement for Final certification. At Level 1, the OSA must affirm annually that it has reassessed its

environment. Security requirement CA.L2-3.12.2 allows for the development and implementation of an operational plans of action designed to correct deficiencies and reduce or eliminate vulnerabilities in organizational systems. The CMMC rule does not prohibit an OSA from using an operational plan of action at any CMMC level to address necessary information system updates, patches, or reconfiguration as threats evolve. These are different from POA&Ms permitted under a Conditional certification assessment. The DoD has updated the rule to make this distinction clear. The Department also updated the rule to include a definition and clarity for enduring exceptions. The DoD CIO option for variances in DFARS clause 252.204-7012 is beyond the scope of this rule. Operational plans of action are the appropriate mechanism to handle CSPs, ESPs (not a CSP) and third-party vendors that are no longer compliant with a CMMC requirement. Operational plans of action may be necessary when the relevant security requirement or control was fully implemented, but a vulnerability or deficiency is discovered after gaining a CMMC final compliance status, such as, but not limited to, routine updates, patches, or updates to CMMC compliance status. For purposes of CMMC compliance, operational plans of action are acceptable and are not subject to the 180-day timetable established for initial assessment. In addition, the rule has been modified to include a definition for Enduring Exceptions. The DoD does not accept the recommendation to change the criteria for POA&Ms or the timeline allowed to remediate open POA&M items. The 180-day period allowed for POA&Ms and the determination of which weighted practices can be placed on a POA&M was a risk-based decision. The determination considers the relative risk DoD is willing to accept when a particular practice is not met and the amount of risk the DoD is willing to accept for those security practices that go ·NOT MET· for an extended period. The DoD declined to edit the rule regarding the closeout of security requirements that are not allowed on the POA&M as stated in §.170.21. The decision in this scenario is a business decision between the applicable C3PAO and the OSC.

A record from a system of records maintained by a DOD Component may be disclosed to foreign law enforcement, security, investigatory, or administrative authorities in order to comply with requirements imposed by, or to claim rights conferred in, international agreements and arrangements including those regulating the stationing and status in foreign countries of DOD military and civilian personnel. (7) Disclosure to State and Local Taxing Authorities Routine Use. Any information normally contained in Internal Revenue Service Form W-2, which is maintained in a record from a system of records maintained by a DOD component, may be disclosed to state and local taxing authorities with which the Secretary of the Treasury has entered into agreements pursuant to 5 U.S.C. sections 5516, 5517, and 5520 and only to those state and local taxing authorities for which an employee or military member is or was subject to tax regardless of whether tax is or was withheld. This routine use is in accordance with Treasury Fiscal Requirements Manual Bulletin 76-07. (8) Disclosure to the Office of Personnel Management Routine Use. A record from a system of records subject to the Privacy Act and maintained by a DA activity may be disclosed to the Office of Personnel Management concerning information on pay and leave, benefits, retirement deductions, and any other information necessary for Office of Personnel Management to carry out its legally authorized Government-wide personnel management functions and studies. (9) Disclosure to the Department of Justice for Litigation Routine Use. A record from a system of records maintained by a DOD component may be disclosed as a routine use to any component of the Department of Justice for the purpose of representing the Department of Defense, or any officer, employee, or member of the Department in pending or potential litigation to which the record is pertinent. (10) Disclosure to Military Banking Facilities Overseas Routine Use. Information as to current military addresses and assignments may be provided to military banking facilities who provide banking services overseas and who are reimbursed by the Government for certain checking and (printed page 46069) loan losses. For personnel separated, discharged, or retired from the Armed forces, information as to last known residential or home of record address may be provided to the military banking facility upon certification by a banking facility officer that the facility has a returned or dishonored check negotiated by the individual or the individual has defaulted on a loan and that if restitution is not made by the individual, the U.S. Government will be liable for the losses the facility may incur. (11) Disclosure of Information to the General Services Administration Routine Use.

3.2.1 Service Discovery Mechanism Threats The basic functions in a service discovery mechanism are:
 - Service registration and de-registration.

authoritative sources for known vulnerabilities, such as those referenced above, and remediating any identified vulnerabilities. When a vulnerability is discovered, a regulated entity, through its

patch management program, should have in place a policy and procedure for applying any available patches or implementing reasonable and appropriate compensating controls if a patch is not available. Remediation may be as simple as applying a vendor-offered software patch or, in the case of software no longer supported by a vendor, designing and implementing reasonable and appropriate compensating controls to reduce the risk of the vulnerability. The policies and procedures required by the proposed standard for patch management in proposed 45 CFR 164.308(a)(4)(i) also would be implemented in part by the proposed implementation specifications associated with the proposed standard for vulnerability management. Those proposed implementation specifications would require the deployment of technical controls to ensure the patch management program is carried out, automated vulnerability scans, and penetration testing, all of which may identify when a patch or compensating control has not been put in place. The Department envisions that the full implementation of all of the proposed standards and implementation specifications would effectively reduce the risk to ePHI.

j. Section 164.312(i)(1)-Standard: Data Backup and Recovery The Security Rule requires regulated entities to regularly create copies of ePHI to ensure that it can be restored in the event of a loss or disruption. [815] However, OCR's enforcement experience indicates that regulated entities could benefit from a more specific standard. Consistent with the proposed standard for contingency planning at 45 CFR 164.308(a)(13)(ii)(B) , the Department proposes to add a standard for a new technical safeguard for data backup and recovery. This new standard would require a regulated entity to deploy technical controls to create and maintain exact retrievable copies of ePHI. The proposed changes would remove the existing implementation specification for this activity from the physical safeguards section and place it within technical safeguards. The Department also proposes to modify the language of the existing requirement by removing the limitation that it applies before moving equipment, so that it applies broadly and comprehensively. Elevating data backup and recovery to a standard would also increase the prominence of this requirement and highlight the liability of regulated entities for creating the capacity to restore systems after a data breach. The Department proposes four new implementation specifications for the data backup and recovery standard. The first, 45 CFR 164.312(i)(2)(i)

Multiple commenters wanted more information about the roll-out of the CMMC pilot program, including transparency about which acquisition programs are being considered for inclusion prior to the release of a solicitation. Commenters requested details on the provisional period, whether there would be a break between the pilot program and the official launch of the CMMC Program, whether there would be an assessment on the effectiveness of the pilot, and if lessons learned from the pilot would be shared across the community. Response: CMMC 1.0 did include a CMMC Pilot program; however, CMMC 2.0 does not include pilots. Instead, upon the effective date of the associated CMMC DFARS rule, the Department intends to begin including CMMC self-assessment requirements when applicable, for protection of FCI and CUI. (printed page 89072)

c. Communicating CMMC Requirements Comment: Two commenters requested that, during the phased rollout of CMMC, defense contractors be forewarned of DoD plans to include a CMMC requirement in an upcoming solicitation. They asked for transparency with respect to which contracts were being considered for CMMC requirements. Response: Offerors and contractors will be informed of CMMC requirements in solicitations through (1) the specification of a required CMMC Level, and (2) inclusion of the appropriate DFARS provisions or clauses. There is no plan to advertise a list of solicitations that will or may include CMMC requirements. The implementation plan described in § 170.3(e) addresses phase-in of CMMC requirements.

d. Market Capacity for Assessments Comment: Multiple commenters wanted details about assessor availability and were concerned that a lack of assessors would impact the schedule for including CMMC requirements in solicitations and contractor planning to attain CMMC certification to meet those requirements. Response: The phased implementation plan described in § 170.3(e) is intended to address ramp-up issues, provide time to train the necessary number of assessors, and allow companies the time needed to understand and implement CMMC requirements. An extension of the implementation period or other solutions may be considered in the future to mitigate any C3PAO capacity issues, but the Department has no such plans at this time. If changes to the implementation plan occur, DoD policies that govern requirements definition in the acquisition process will be modified.

e. Certification Sustainment During Validity Period Comment:

Accordingly, timely implementation of patches for known vulnerabilities is crucial to maintaining the security of ePHI. Many cyberattacks could be prevented or substantially mitigated if regulated entities implemented activities to manage the implementation of patches, updates, and upgrades to comply with the Security Rule's requirements for risk management, which can deter one of the common types of attacks: exploitation of known vulnerabilities. If an attack is successful, the intruder

often will encrypt a regulated entity's ePHI to hold it for ransom, or exfiltrate the data for future purposes including identity theft or blackmail. Cyberattacks are especially concerning in the health care sector because they can disrupt the provision of health care services. Exploitable vulnerabilities can exist in many parts of a regulated entity's information systems, but often, known vulnerabilities can be mitigated by applying vendor patches, updating software or system configurations, or upgrading to a newer version of the product. If a patch, update, or upgrade is unavailable, vendors often suggest actions to take, that is, compensating controls, to mitigate a newly discovered vulnerability. Such actions could include modifications of configuration files or disabling of affected services. Regulated entities should pay careful attention to cybersecurity alerts describing newly discovered vulnerabilities. These alerts often include information on mitigation activities and patching. Risk management processes that are compliant with the Security Rule include identifying and mitigating risks and vulnerabilities that unpatched software poses to an organization's ePHI. Mitigation activities could include installing patches if patches are available and patching is reasonable and appropriate. In situations where patches are not available (e.g., obsolete or unsupported software) or testing or other concerns weigh against patching as a mitigation solution, [492] regulated entities should implement reasonable compensating controls to reduce the risk of identified vulnerabilities to a reasonable and appropriate level (e.g., restricting network access or disabling network services to reduce vulnerabilities that could be exploited via network access). Security vulnerabilities may be present in many types of software, including databases, EHRs, operating systems, email, and device firmware. Each type of program would have its own unique set of vulnerabilities and challenges for applying patches, but identifying and mitigating the risks unpatched software (printed page 943) poses to ePHI is important to ensuring that ePHI is protected. [493]

(Response) As discussed in response to comment 74, several statutes and the agency's information disclosure regulations at parts 20 and 21 govern the agency's ability to disclose information to the public, including information obtained under section 306 of the Bioterrorism Act. For example, section 301 of the FD&C Act prohibits any person from using *** to his own advantage, or revealing, other than to the Secretary or officers or employees of the Department, or to the courts ***, any information acquired under authority of [section 414 or 704] concerning any method or process which as a trade secret is entitled to protection ***. FDA already has procedures in place to ensure that FDA staff follow these laws. See, e.g., FDA Staff Manual Guide sections 2280.10, 3250.15, and 3291.5. Furthermore, the record provisions in the Bioterrorism Act recognize that FDA may obtain trade secret or confidential information, and direct the Secretary to *** take appropriate measures to ensure that there are in effect effective procedures to prevent the unauthorized disclosure of [such information] ***. (21 U.S.C. 414(c)). FDA is planning to reemphasize in instructions to FDA personnel the importance of current protections and legal requirements against the unauthorized disclosure of any trade secret or confidential information that is obtained. FDA has previously issued information disclosure regulations applicable to information FDA obtains, and these regulations are applicable to information FDA obtains under the Bioterrorism Act (parts 20 and 21). FDA notes that these regulations are applicable regardless of whether the person supplying the information is ultimately determined to be an unaffected source, incorrectly implicated source, or the victim of food contaminated in premeditated form. Therefore, it is not necessary for FDA to issue additional information disclosure regulations. Moreover, FDA routinely reviews, evaluates, investigates and maintains confidential, trade secret information that encompasses sophisticated, cutting edge technologies, as well as confidential records that contain formulations and other trade secret information. Based upon FDA's track record of consistently ensuring the confidentiality of this type of information, we have attained the trust of the pharmaceutical, medical device and biologics industries. Moreover, the utilization of such information by an FDA employee for his or her own advantage, or the revelation of such information to outside parties beyond the scope allowed by the FD&C Act, is a prohibited act (21 U.S.C. 331(j)) subject to criminal prosecution.

- Item 1: DPA Identification . Report your name, routing symbol and telephone number and copy the DPA's title and address from the DPI and DPA Identification . Figure 1, No. 5 on page 4. - Item 2: Configuration . The definition of "DPA" is on page 2 of these guidelines. There is additional information for identifying the DPA on page 3. Review this information and then check one of the six boxes on the form that most closely describes the particular DPA. If none of the types apply, check the box marked "Other" and write a brief description of the DPA. Later, you will use your answer to this item as the basis for selecting a method for assessing risks to the DPA. (See pages 17 and 28.)

- Item 3: Hardware Inventory . List the DPA's hardware. If the hardware is already listed in the System Inventory Directory maintained by AMS-300, the Personnel Property Management Information System (PPMIS) , or in another listing, check the appropriate box(es) and attach current print-outs.

2. CONFIGURATION Check the box that most closely describes the configuration of the DPA:

3.2.2 | Communication Channels... 3.2.2 Communication Channels Participants indicated how their organizations communicate and disseminate security awareness information.

Insert the clause at 52.204-21, Basic Safeguarding of Covered Contractor Information Systems, in solicitations and contracts excluding solicitations and contracts solely for the acquisition of-

(a) COTS items; or (b) Federally-funded basic and applied research in science, technology, and engineering at colleges, universities, and laboratories in accordance with National Security Decision Directive 189 when the agency does not provide any covered Federal information to the contractor.

4.1301 [Amended] 13. Amend section 4.1301 by-

a. Removing from paragraph (a) the phrases "PUB Number 201", and "Federally-controlled information" and adding the phrases "201" and "Federal information" in their places, respectively.

b. Removing from paragraph (b) the phrases "PUB 201", and "Federally-controlled information" and adding the phrases "201" and "Federal information" in their places, respectively.

4.1303 [Amended] 14. Amend section 4.1303 by removing the words "Federally-controlled information" and adding "Federal information" in its place.

Subpart 4.19 [Removed and Reserved] 15. Remove and reserve subpart 4.19.

PART 5-PUBLICIZING CONTRACT ACTIONS 5.202 [Amended] 16. Amend section 5.202 in paragraph (a)(8) by removing the phrase "proprietary information" and adding "controlled unclassified information (e.g., general proprietary business information)" in its place.

5.301 [Amended] 17. Amend section 5.301 in paragraph (b)(1) by removing the phrase "proprietary information" and adding "controlled unclassified information (e.g., general proprietary business information)" in its place.

PART 7-ACQUISITION PLANNING 18. Amend section 7.103 by adding paragraph (z) to read as follows:

7.103 Agency-head responsibilities. * * * * * (z) Ensuring agency planners-

(1) Comply with the requirements of Executive Order 13556 of November 4, 2010, as implemented at 32 CFR part 2002 and in agency procedures, for controlled unclassified information (CUI). This does not apply to acquisitions for commercially available off-the-shelf items or for Federally-funded basic and applied research in science, technology, and engineering at colleges, universities, and laboratories in accordance with National Security Decision Directive 189 when the agency does not provide any CUI to the contractor; and

(2) Identify all categories of CUI in proposed acquisitions and incorporate them and accompanying CUI standards in requirements planning and the SF XXX, Controlled Unclassified Information (CUI) Requirements, as appropriate (see 4.403-4, 11.002(i), and 39.105).

* * * * *

19. Amend section 7.105 by-

a. Removing from paragraph (b)(18)(i) the phrase "(see subpart 4.4)" and adding "(see 4.402)" in its place;

b. Removing from paragraph (b)(18)(iii) the phrase "Federally-controlled information" and adding "Federal information" in its place;

c. Revising paragraph (b)(18)(iv); and

d. Adding paragraph (b)(18)(v). The revision and addition read as follows:

7.105 Contents of written acquisition plans. * * * * * (b) * * * (18) * * *

865. "In 2003, the Department declined a commenter's suggestion to change the term "periodically" to "at least annually." At that time, we said that documentation must be updated as needed to reflect security measures currently in effect and that the requirement allowed individual entities to establish review and update cycles as deemed necessary because it would vary dependent upon a given entity's size, configuration, environment, operational changes, and the security measures implemented. 68 FR 8334 , 8361 (Feb. 20, 2003). Back to Citation 866. "HIPAA set forth the compliance dates for the initial standards. 42 U.S.C. 1320d-4 ; see also 68 FR 8334 , 8351 (Feb. 20, 2003). Back to Citation 867. "Similarly, a business associate subcontractor would need to report to the business associate. See "Business Associate Contracts," Office for Civil Rights, U.S. Department of Health and Human Services (June 16, 2017) (A "business associate" also is a subcontractor that creates, receives, maintains, or transmits PHI on behalf of another business associate), <https://www.hhs.gov/hipaa/for-professionals/covered-entities/sample-business-associate-agreement-provisions/index.html> . Back to Citation 868. "Proposed 45 CFR 164.314(a)(2)(i)(D) . Back to Citation 869. "The Department has previously included transition provisions to ensure that important functions of the health care system were not impeded. See, e.g., 65 FR 82462 (Dec. 28, 2000); 67 FR 53182 (Aug. 14, 2002); 78 FR 5566 (Jan. 25, 2013). Back to Citation 870. " See proposed 45 CFR 164.308(b)(1)(i) . Back to Citation 871. See id. Back to Citation 872. 45 CFR 164.314(a)(2)(i)(A) . Back to Citation 873. 45 CFR 164.314(a)(2)(i)(B) . Back to Citation 874. "Or to the business associate from a business

associate subcontractor. Back to Citation 875. ·Proposed 45 CFR 164.314(a)(2)(i)(D) . Back to Citation 876. ·Or business associate's contract with the subcontractor. Back to Citation 877. 45 CFR 164.306(a) . Back to Citation 878. 45 CFR 164.508(a)(1)(ii)(A) . Back to Citation 879. 45 CFR 164.308(a)(1)(ii)(B) . Back to Citation 880. · See ·Post-Quantum Cryptography, Quantum Background,· U.S. Department of Homeland Security (last accessed July 23, 2024), <https://www.dhs.gov/quantum> ; see also ·Quantum-Readiness: Migration to Post-Quantum Cryptography,· Cybersecurity & Infrastructure Security Agency, National Security Agency, and National Institute of Standards and Technology, p. 1 (Aug. 21, 2023), <https://media.defense.gov/2023/Aug/21/2003284212/-1/-1/0/CSI-QUANTUM-READINESS.PDF> . Back to Citation 881. ·Post-Quantum Cryptography, Quantum Background,· supra note 880. Back to Citation 882. · See ·Post-Quantum Cryptography PQC,· Computer Security Resource Center, National Institute of Standards and Technology, U.S. Department of Commerce (July 19, 2024), <https://www.nist.gov/pqcrypto> . Back to Citation 883. · See ·Post-Quantum Cryptography, Quantum Background,· supra note 880. Back to Citation

In November 2021, the Department announced an updated program structure with revised requirements designed to achieve the primary goals identified by DoD's internal review of the CMMC Program. With the implementation of the revised CMMC program, the Department introduced several key changes that build on and refine the original program requirements. These include: Streamlining the CMMC model from five levels to three levels. Exclusively implementing National Institute of Standards and Technology (NIST) cybersecurity guidelines. Allowing all companies subject to CMMC Level 1 requirements and subset of companies subject to CMMC Level 2 requirements to demonstrate CMMC compliance through self-assessments. Increased oversight of professional and ethical standards of third-party assessors. (printed page 83195) Allowing Plans of Action & Milestones (POA&M) under limited circumstances to achieve conditional certification. In July 2022, the CMMC Program Management Office (PMO) met with the Office of Advocacy for the U.S. SBA to address the revisions planned for CMMC and again met in July 2023 to review the proposed 32 CFR part 170 CMMC Program rule updates that are responsive to prior SBA concerns. As a result of the alignment of CMMC requirements to NIST guidelines, the Department's requirements continue to evolve as changes are made to the underlying NIST SP 800-171 R2 and NIST SP 800-172 Feb2021 requirements. Such changes will not be effective as CMMC requirements unless and until made effective through rulemaking. Objectives of, and Legal Basis for, the Rule Legal Basis: 5 U.S.C. 301 ; Sec. 1648, Public Law 116-92 , 133 Stat. 1198. The objective of this final CMMC Program rule is to provide the Department with increased assurance that a defense contractor can adequately protect FCI and CUI commensurate with the risk, also accounting for information flow down to its subcontractors in a multi-tier supply chain. This rule meets the objective by providing a mechanism to assess contractor and subcontractor implementation of DoD's cyber security protection requirements for FCI and CUI. Implementation of the CMMC Program is intended to address the following policy issues: (a) Verification of a Contractor's Cybersecurity Posture Effective June 2016, FAR clause 52.204-21 Basic Safeguarding of Contractor Information Systems, requires Federal contractors and subcontractors to implement 15 basic safeguarding requirements, as applicable, to protect contractor information systems that process, store, or transmit FCI.

(4) Calculate each request on the basis of the price, costs (including the cost to complete), subcontractor financing, and progress payment liquidations of the lot to which it applies; and (5) Distribute costs among lots in a manner acceptable to the Administrative Contracting Officer. (c) Submit a separate progress payment request for U.S. and FMS requirements in accordance with the DFARS clause 252.232-7002, Progress Payments for Foreign Military Sales Acquisitions, of this contract. (End of clause) [FR Doc. 2023-11138 Filed 5-24-23; 8:45 am] BILLING CODE 5001-06-P

ial applications. This effort is being carried out through the Process Control Security Requirements Forum (PCSRF), an industry group organized under the National Information Assurance Program (NIAP). NIAP is a joint effort between the NIST and the National Security Agency (NSA). As part of the Critical Infrastructure Protection Program, NIST and NSA are working to provide technical support and guidance to industry to improve the Nation's security posture. The outcome of this work will be the development and dissemination of best practices and ultimately security specifications that will be used in the procurement, development, and retrofit of industrial control systems.

Pursuant to DFARS clause 252.204-7012, DoD has required certain defense contractors and subcontractors to implement the security protections set forth in the National Institute of

Standards and Technology (NIST) Special Publication (SP) 800-171 R2 to provide adequate security for CUI that is processed, stored, or transmitted on contractor information systems. The CMMC Program provides the Department the mechanism needed to verify that a defense contractor or subcontractor has implemented the security requirements at each CMMC Level and is maintaining that status across the contract period of performance, as required. In calendar year (CY) 2021 DoD paused the planned CMMC rollout to conduct an internal review of the CMMC Program. The internal review resulted in a refined and streamlined set of requirements that addressed many of the concerns identified in the public comments received relating to the initial CMMC Program. These changes have been incorporated into the revised CMMC Program structure and policies. In July 2022, the CMMC PMO met with the Office of Advocacy for the United States Small Business Administration (SBA) to address the revisions planned to the CMMC Program that are responsive to prior SBA concerns. The CMMC Program will enhance the ability of the DoD to safely share FCI and CUI with defense contractors and know the information will be suitably safeguarded. Once fully implemented, CMMC will incorporate a set of cybersecurity requirements into acquisition contracts to provide verification that applicable cyber protections have been implemented. Under the CMMC Program, defense contractors and subcontractors will be required to implement certain cybersecurity protection requirements tied to a designated CMMC level and either perform a self-assessment or obtain an independent assessment from either a C3PAO or DCMA DIBCAC as a condition of a DoD contract award. CMMC is designed to validate the protection of FCI and CUI that is shared with and generated by the Department's contractors and subcontractors. Through protection of information by adherence to the requirements verified in the revised CMMC Program, the Department and its contractors will prevent disruption in service and the loss of intellectual property and assets, and thwart access to FCI and CUI by the nation's adversaries.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 Any circumstance or event with the potential to adversely impact organizational operations, organizational assets, 3110 individuals, other organizations, or the Nation through a system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service. [21] threat information Any information related to a threat that might help an organization protect itself against the threat or detect the activities of an actor. Major types of threat information include indicators, TTPs, security alerts, threat intelligence reports, and tool configurations. [14] threat intelligence Threat information that has been aggregated, transformed, analyzed, i

Responsibilities upon completion of the subcontracts. (1) Upon completion of the subcontract, the subcontractor may retain classified material received or generated under the subcontract for a two-year period, in accordance with the provisions in § 117.13(d)(5). (2) If retention is required beyond the two-year period, the subcontractor must request written retention authority through the prime contractor to the GCA, including the information required by § 117.15(j). (3) If retention authority is approved by the GCA, the prime contractor will issue a final Contract Security Classification Specification, or equivalent, annotated to provide the retention period and final disposition instructions. (d) Notification of invalidation, marginal, or unsatisfactory conditions. The prime contractor will be notified if the CSA discovers marginal or unsatisfactory conditions at the subcontractor's facility or if the CSA invalidates the subcontractor's facility clearance. Once notified, the prime contractor will follow the instructions received on what action, if any, should be taken in order to safeguard classified material relating to the subcontract.

§ 117.18 Information system security. (a) General. (1) Contractor information systems that are used to capture, create, store, process, or distribute classified information must be properly managed to protect against unauthorized disclosure of classified information. The contractor will implement protective measures using a risk-based approach that incorporates minimum standards for their insider threat program in accordance with CSA-provided guidance. (2) The CSA will issue guidance based on requirements for federal systems, pursuant to 44 U.S.C. Ch. 35 of subchapter II, also known as the 'Federal Information Security Modernization Act,' and as set forth in National Institute of Standards and Technology (NIST) Special Publication 800-37 (available at: <https://csrc.nist.gov/publications/detail/sp/800-37/rev-2/final>), Committee on National Security Systems (CNSS) Instruction 1253 (available at: <https://www.cnss.gov/CNSS/openDoc.cfm?QwPYrAJ5Ldq+s+jvttTznQ=->), and other applicable CNSS and NIST publications (e.g., NIST Special Publication 800-53). (b) Information system security program. The contractor will maintain an information system security program that supports overall information security by incorporating a risk-based set of management, operational, and technical

security controls in accordance with CSA-provided guidance. The contractor will incorporate into the program: (1) Policies and procedures that reduce information security risks to an acceptable level and address information security throughout the information system life cycle. (2) Plans and procedures to assess, report, isolate, and contain data spills and compromises, to include sanitization and recovery methods. (3) Information system security training for authorized users, as required in CSA provided guidance.

Eight comments were received on safeguarding, § 117.15, to include four on open storage areas and another four on intrusion detection systems (IDS). Commenters also requested more guidance on open storage area requirements included in the previous NISPOM DoD Manual, to include procedures for leaving an open storage area unattended during business hours, whether self-approval authority can still be delegated to FSOs by a CSA, procedures to ensure the structural integrity of the space, and whether open bin and open shelf storage is still permitted. DoD is proposing updated text in § 117.15(a) and (c) to address several of these comments (e.g., procedures for leaving an open storage area unattended during business hours and delegation of approval authority to FSOs if agreed to by the CSA, respectively) and as a result added a definition for 'pedestrian door locks' from the added text on security checks. DoD is also proposing updated text in paragraph 117.15(d) to provide more clarity on required investigative response to alarms for IDS. More guidance on safeguarding for those contractors under DoD cognizance will be provided via forthcoming ISLs, as appropriate. DoD is also proposing additional text to § 117.15(e) regarding information management systems to more accurately reflect the terminology for classified information systems, and as a result added the term 'authorization to operate' to the definitions section in § 117.3. Finally, DoD is proposing additional text to § 117.15(e)(6) to provide more clarity on the requirements for the reproduction of classified information, to include accountability, control, and marking requirements of the reproduced classified information, and procedures for waste products resulting from the reproduction. A commenter questioned the accuracy of the text in § 117.17(a)(3) which stated that if an entity eligibility determination could not be completed in time to qualify the prospective subcontractor for participation in a procurement action, that the CSA will continue the entity eligibility determination processing for future contract consideration. After review of this text, DoD has concluded this text provides guidance to CSAs, rather than contractors and is proposing it for deletion. Joint Personnel Adjudication System Finally, the reference to the Joint Personnel Adjudication System is proposed for deletion from the list of approved information collections as part of the Paperwork Reduction Act section because it has been discontinued and replaced by the Defense Information System for Security. The text in § 117.5(d) has also been proposed for updating to reflect only the Defense Information System for Security is used for the initiation, investigation, and adjudication of information relevant to DoD security clearances and employment suitability determinations. Expected Impact of the Proposed Rule and Changes Being Proposed Based on Public Comment

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. that and now have automated tools. Our onboarding site is a self-registration site so that our new staff can go and self-register, take their training, and then that ties into our primary learning center once they're on board and approved. We reconcile those transcripts. So, we do have now the automated means where we do tie it into our backend account management system so that, truly, people aren't getting access to things before they've taken that training and signed the rules of behavior.

There are three types of documents relating to the Privacy Act Program that must be published in the Federal Register . They are the DA Privacy Program policy and procedures (AR 340-21), the DA exemption rules, and Privacy Act system of records notices. (b) Rulemaking procedures . (1) DA Privacy Program procedures and exemption rules are subject to the formal rulemaking process. (2) Privacy Act system of records notices are not subject to formal rulemaking and are published in the Federal Register as Notices, not Rules. (3) The Privacy Program procedures and exemption rules are incorporated into the Code of Federal Regulations (CFR). Privacy Act system of records notices are not published in the CFR. § 505.12 Privacy Act enforcement actions. (a) Judicial Sanctions. The

Act has both civil remedies and criminal penalties for violations of its provisions. (1) Civil remedies. The DA is subject to civil remedies for violations of the Privacy Act. In addition to specific remedial actions, 5 U.S.C. 552a(g) may provide for the payment of damages, court costs, and attorney's fees. (2) Criminal penalties. A DA official or employee may be found guilty of a misdemeanor and fined not more than \$5,000 for willfully: (i) Disclosing individually identifiable personal information to one not entitled to the information; (ii) Requesting or obtaining information from another's record under false pretenses; or (iii) Maintaining a system of records without first meeting the public notice requirements of the Act. (b) Litigation Status Sheet. (1) When a complaint citing the Privacy Act is filed in a U.S. District Court against the Department of the Army, an Army Component, a DA Official, or any Army employee, the responsible system manager will promptly notify the Army Litigation Division, 901 North Stuart Street, Arlington, VA 22203-1837. (2) The Litigation Status Sheet at appendix E of this part provides a standard format for this notification. At a minimum, the initial notification will have items (a) through (f) provided. (3) A revised Litigation Status Sheet must be provided at each stage of the litigation. (4) When a court renders a formal opinion or judgment, copies must be provided to the Defense Privacy Office by the Army Litigation Division. (c) Administrative Remedies-Privacy Act complaints. (1) The installation level Privacy Act Officer is responsible for processing Privacy Act complaints or allegations of Privacy Act violations. Guidance should be sought from the local Staff Judge Advocate and coordination made with the system manager to assist in the resolution of Privacy Act complaints. The local Privacy Act officer is responsible for: (i) Reviewing allegations of Privacy Act violations and the evidence provided by the complainants; (ii) Making an initial assessment as to the validity of the complaint, and taking appropriate corrective action;

Back to Citation 327. 42 U.S.C. 1320d-2(d)(1)(A) . Back to Citation 328. --ANSI/NIST-ITL Standard, National Institute of Standards and Technology, U.S. Department of Commerce (Feb. 3, 2023), <https://www.nist.gov/programs-projects/ansinist-itl-standard> . Back to Citation 329. · See section 13412(a) of the HITECH Act, as amended by section 1 of Public Law 116-321 , 134 Stat. 5072 (Jan. 5, 2021) (codified at 42 U.S.C. 17941(a)(1)). Back to Citation 330. Id. Back to Citation 331. · See Letter from NCVHS Chair Jacki Monson (2022), *supra* note 123; Letter from NCVHS Chair Jacki Monson (2023), *supra* note 123. Back to Citation 332. 42 U.S.C. 1320d-1(f) . Back to Citation 333. 42 U.S.C. 1320d-1(c)(3)(A)(ii) . Back to Citation 334. 45 CFR 160.103 (definition of ·Electronic media·). Back to Citation 335. 78 FR 5566 (Jan. 25, 2013). Back to Citation 336. Id. at 5576. Back to Citation 337. Id. Back to Citation 338. Id. Back to Citation 339. ·A standard telephone line, often described as a traditional landline, uses circuit-switched voice communication service technologies through the Public Switched Telephone Network. The information transmitted through such traditional telephones is not electronic. Back to Citation 340. ·VoIP technologies convert audio into a digital signal that is then transmitted over the internet. See Voice Over internet Protocol (VoIP), Federal Communications Commission, <https://www.fcc.gov/general/voice-over-internet-protocol-voip> . Back to Citation 341. ·A 2022 report by the Federal Communications Commission stated that the ·number of fixed retail switched-access lines declined over the past three years at a compound annual rate of 12.3%, while interconnected VoIP subscriptions increased at a compound annual growth rate of 0.7%.· See ·2022 COMMUNICATIONS MARKETPLACE REPORT, Federal Communications Commission, p. 122 (Dec. 30, 2022), <https://docs.fcc.gov/public/attachments/FCC-22-103A1.pdf> . Back to Citation 342. · See ·NIST Privacy Framework: A Tool for Improving Privacy Through Enterprise Risk Management, Version 1.0, National Institute of Standards and Technology, U.S. Department of Commerce, p. 29 (Jan. 16, 2020) (see definition of ·data processing·), <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.01162020.pdf> . Back to Citation 343. · See Maithilee Joshi, et al., ·Delegated Authorization Framework for EHR Services Using Attribute-Based Encryption, IEEE Transactions on Services Computing, Volume 14, No. 6, p. 1 (2021) (discussing that health care providers are increasingly using Cloud-based EHR services to manage ePHI, which increases the possibility of attacks on ePHI), <https://ebiquity.umbc.edu/get/al/publication/1126.pdf> ; see also ·Security Standards: Technical Safeguards, HIPAA Security Series, Office for Civil Rights, U.S. Department of Health and Human Services, (May 2005, revised Mar. 2007) (The goal of encryption is to protect ePHI from being accessed and viewed by unauthorized users.),

3.3.8 Program Controls Access controls must also be in place to protect programs, JCL and related documentation from unauthorized A program may be proprietary for its intrinsic access.

3.1.5. 3.1.5): A one-time secret obtained from a device or application held by the subscriber that requires activation by a second authentication factor · Single-factor cryptographic authentication (Sec. 3.1.5) · Multi-factor cryptographic authentication (Sec.

3.4.1 | Refresh... 3.4.1 Refresh Access control functions need information on how often an attribute's value is pulled or obtained, as well as how securely the attribute's value is processed when it is needed.

9. Adjustments to Account for Records Requests Made on the Weekends If there are 4 sets of weekends during the 29 day traceback time period in which records are inaccessible, then the estimated calendar duration (including weekends) of a current traceback investigation becomes much longer. To allow more accurate comparison of the time savings between current traceback times with those projected under alternative policy options requiring 4 and 8 hours, and up to 24 hours records access, we adjust the estimate of current traceback times to account for requests that would be made on weekends following issuance of this final rule. Most current records requests are made during the week, because establishments may not be open or key personnel may be absent on weekends. However, this final rule requires records access when requests are made on either weekdays or weekends. Consequently, we assume that there is a 1 in 7 chance of requesting records on a Saturday, and a 1 in 7 chance of requesting records on a Sunday if FDA were conducting a traceback investigation of a food for which it had a reasonable belief the food was adulterated and presented a serious threat of serious adverse health consequences or death to humans or animals. A 24-hour records access requirement would improve current traceback times by allowing weekend records access requests. We assume that a records access request that would be made on a Saturday or Sunday following issuance of this final rule, would currently not be made until the following Monday. Taking this assumption into account, we estimate that the current time to satisfy a records request made on a Saturday to be 3 to 5 days (i.e., 2 days, plus 1 to 3 days), or an average of 4 days for 1/7 of all access requests (i.e., records requested on a Saturday), and 2 to 4 days (i.e., 1 day, plus 1 to 3 days), or an average of 3 days for 1/7 of all access requests (i.e., records requested on a Sunday). With the average of 1.2 days for records analysis times, the adjusted estimate of the total time for satisfying a records access request and records analysis is an average of 5.2 days (1.2 days, plus an average of 4 days) for requests made on a Saturday, and 4.2 days (1.2 days, plus an average of 3 days) for requests made on a Sunday. The adjusted estimate of current traceback times is computed as an expectation of traceback times taking into account the probabilities of records requests made on weekdays and weekends. Assuming nine investigative visits per traceback investigation, the adjusted estimate of the current traceback time is approximately 33 days $((3.3 \text{ days} \times 5/7) + (4.2 \text{ days} \times 1/7) + (5.2 \text{ days} \times 1/7)) \times 9 \text{ visits}$. The adjusted estimate of the current traceback duration is reasonably consistent with the current traceback durations reported by traceback personnel of between 6 and 8 weeks for eggs and fresh produce, and 3 days for packaged products that contain lot code information on the labeling.

(x) The Assistant Chief of Staff for Installation Management is authorized to act on requests for records relating to planning, programming, execution and operation of Army installations. This includes base realignment and closure activities, environmental activities other than litigation, facilities and housing activities, and installation management support activities. (y) The Commander, U.S. Army Intelligence and Security Command, is authorized to act on requests for intelligence and security records, foreign scientific and technological records, intelligence training, intelligence threat assessments, and foreign liaison information, mapping and geodesy information, ground surveillance records, intelligence threat assessment, and missile intelligence data relating to tactical land warfare systems. (z) The Commander, U.S. Army Combat Readiness Center (formerly U.S. Army Safety Center), is authorized to act on requests for Army safety records. (aa) The Commander, U.S. Army Test and Evaluation Command (ATEC), is authorized to act on requests for the records of ATEC headquarters, its subordinate commands, units, and activities that relate to test and evaluation operations. (bb) The General Counsel, Army and Air Force Exchange Service, is authorized to act on requests for Army and Air Force Exchange Service records, under AR 60-20/AFR 147-14. (cc) The Commandant, United States Disciplinary Barracks (USDB) is authorized to act on records pertaining to USDB functional area responsibilities relating to the administration and confinement of individual military prisoners at the USDB. This includes, but is not limited to, all records pertaining to the treatment of military prisoners; investigation of prisoner misconduct; management, operation, and administration of the USDB confinement facility; and related programs which fall directly within the scope of the Commandant's functional area of command and control.

(dd) The Commander, U.S. Army Community and Family Support Center (USACFSC) is authorized to act on requests for records pertaining to morale, welfare, recreation, and entertainment programs; community and family action programs; child development centers; non-appropriated funds issues, and private organizations on Army installations. (ee) The Commander, Military Surface Deployment and Distribution Command (formerly Military Traffic Management Command) is authorized to act on requests for records pertaining to military and commercial transportation and traffic management records. (ff) The Director, Installation Management Agency (IMA) is authorized to act on requests for all IMA records. (gg) Special Denial Authority's authority for time-event related records may be designated on a case-by-case basis. These will be published in the Federal Register . You may contact the Department of the Army, Freedom of Information and Privacy Office to obtain current information on special delegations. Appendix C to Part 505-Privacy Act Statement Format (a) Authority:

(3) The Judge Advocate General will serve as the Denial Authority on requests made pursuant to the Privacy Act of 1974 for access to or amendment of Army records, regardless of functional category, concerning actual or potential litigation in which the United States has an interest. (4) The Chief, DA Freedom of Information Act and Privacy Office (FOIA/P), U.S. Army Records Management and Declassification Agency will-

- (i) Develop and recommend policy;
- (ii) Execute duties as the Army's Privacy Act Officer;
- (iii) Promote Privacy Act awareness throughout the DA;
- (iv) Serve as a voting member on the Defense Data Integrity Board and the Defense Privacy Board;
- (v) Represent the Department of the Army in DOD policy meetings; and
- (vi) Appoint a Privacy Act Manager who will-

(A) Administer procedures outlined in this part; (B) Review and approve proposed new, altered, or amended Privacy Act systems of records notices and subsequently submit them to the Defense Privacy Office for coordination; (C) Review Department of the Army Forms for compliance with the Privacy Act and this part; (D) Ensure that reports required by the Privacy Act are provided upon request from the Defense Privacy Office; (E) Review Computer Matching Agreements and recommend approval or denial to the Chief, DA FOIA/P Office; (F) Provide Privacy Act training; (G) Provide privacy guidance and assistance to DA activities and combatant commands where the Army is the Executive Agent; (H) Ensure information collections are developed in compliance with the Privacy Act provisions; (I) Ensure Office of Management and Budget reporting requirements, guidance, and policy are accomplished; and (J) Immediately review privacy violations of personnel to locate the problem and develop a means to prevent recurrence of the problem. (5) Heads of Department of the Army activities, field-operating agencies, direct reporting units, Major Army commands, subordinate commands down to the battalion level, and installations will-

- (i) Supervise and execute the privacy program in functional areas and activities under their responsibility; and
- (ii) Appoint a Privacy Act Official who will-

(A) Serve as the staff advisor on privacy matters; (B) Ensure that Privacy Act records collected and maintained within the Command or agency are properly described in a Privacy Act system of records notice published in the Federal Register ; (C) Ensure no undeclared systems of records are being maintained; (D) Ensure Privacy Act requests are processed promptly and responsively; (E) Ensure a Privacy Act Statement is provided to individuals when information is collected that will be maintained in a Privacy Act system of records, regardless of the medium used to collect the personal information (i.e., forms, personal interviews, stylized formats, telephonic interviews, or other methods);

It is assumed that the mobile devices first responders will use on the future NPSBN-as is the case with their existing LMR devices-will remain under the physical control of first responders for the duration of their shifts. These LMR devices are often affixed to them via a physical tether. First responders need to be able to access the same mission-critical communication services on their next-generation mobile device in a manner similar to the way they currently use their LMR devices. Allowing the use of certain functions without authentication is not without precedent, as many modern mobile operating systems allow users to access certain features without authenticating at the time of use. Common examples include accessing the camera, performing emergency calls, and viewing and interacting with notifications from a variety of applications (e.g., texting). With that concept in mind, compensating controls may be necessary to mitigate threats raised by this security configuration, especially device loss or theft. These controls may include auditing and logging which entities access certain resources, and the ability to remotely wipe a portion, or the entire contents, of a mobile device's storage locations.

-To a consumer reporting agency in accordance with section 3711(e) of Title 31 of the U.S. Code. The name, address, SSN, and other information identifying the individual; amount, status, and history of the claim; and the agency or program under which the case arose may be disclosed. However, before

doing so, agencies must complete a series of steps designed to validate the (printed page 14764) debt and to offer the individual an opportunity to repay it. §-310.16 Department of the Navy exemptions. (a) All systems of records maintained by the DON shall be exempt from the requirements of the access provision of the Privacy Act (5 U.S.C. 552a(d)) under the (k)(1) exemption, to the extent that the system contains information properly classified under E.O. 12958 and that is required by that E.O. to be kept secret in the interest of national defense or foreign policy. This exemption is applicable to parts of all systems of records including those not otherwise specifically designated for exemptions herein that contain isolated items of properly classified information. (1) System identifier and name. N01070-9, White House Support Program. (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958 , as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (C) Records maintained in connection with providing protective services to the President and other individuals under 18 U.S.C. 3506 , may be exempt pursuant to 5 U.S.C. 552a(k)(3) . (D) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (E) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(1), (e)(4)(G) through (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(1) , (k)(2), (k)(3), and (k)(5). (iii) Reasons. Exempted portions of this system contain information that has been properly classified under E.O. 12958

(i) Disclosure of the information is in the public interest because it is likely to contribute significantly to public understanding of the operations or activities of the Government. The factors identified must be met to some degree to warrant waiving or reducing assessable fees in the public interest. (A) The subject of the request . The Components should analyze whether the subject matter of the request involves issues will significantly contribute to the public understanding of the operations or activities of the Department of Defense. Requests for records in the possession of the Department of Defense that were originated by non-government organizations and are sought for their intrinsic content, rather than informative value, will likely not contribute to public understanding of the operations or activities of the Department of Defense. An example of such records might be press clippings, magazine articles, or records forwarding a particular opinion or concern from a member of the public regarding a DoD activity. Similarly, disclosures of records of considerable age may or may not bear directly on the current activities of the Department of Defense; however, the age of a particular record shall not be the sole criterion for denying relative significance under this factor. It is possible to envisage an informative issue concerning the current DoD activities, based on historical documentation. Requests of this nature must be closely reviewed consistent with the requester's stated purpose for desiring the records and the potential for public understanding of DoD operations and activities. (B) The informative value of the information to be disclosed . This factor requires a close analysis of the substantive contents of a record, or portion of the record, to determine whether disclosure is meaningful, and shall inform the public on the operations or activities of the Department of Defense. While the subject of a request may contain information that concerns the Department of Defense, it may not always hold great potential for contributing to a meaningful understanding of these operations or activities. An example of such would be a previously released record that has been heavily redacted, the balance of which may contain only random words, fragmented sentences, or paragraph headings. A determination as to whether a record in this situation will contribute to the public understanding of DoD operations or activities must be approached with caution, and carefully weighed against the arguments offered by the requester. Another example is information already known to be in the public domain. Disclosure of duplicative or nearly identical information already existing in the (printed page 71863) public domain may not add meaningful new information concerning the operations and activities of the Department of Defense. (C) The contribution to an understanding of the subject by the general public likely to result from disclosure

(Response) FDA does not agree that there are millions of direct marketers of food in the United

States. Nor does FDA agree that the burden on direct marketing retailers would be greater than for other retail establishments. However, FDA does agree that the data sources used in the PRIA may not account for many small direct marketers that may not have filed as a sole proprietorship business with the Internal Revenue Service (IRS). While these direct marketers may have been omitted in the PRIA, they are considered exempt in the final rule and are not included in the cost estimates in this analysis. Nevertheless, in order to respond to comments and to estimate the cost of policy options that include very small retailers, FDA does revise its estimate of the number of retail establishments to account for direct marketers that may not have been included in the PRIA. FDA found estimates of 10 million (Ref. 24) and 12 million (Ref. 25) direct marketers in the United States, but these estimates included all the direct marketers of both nonfood and food products in the United States. FDA does not have a complete census of the number of marketers of food versus nonfood products. To approximate the percentage of direct marketers selling food, FDA divided the number of direct marketing companies selling food by the number selling all types of products, using data from the directory of companies on the Web site of a large direct selling trade organization (Ref. 25). Of the 141 companies in the directory, approximately 5 market food or beverages, or approximately 3.5 percent of the total. The number of direct marketing establishments should be captured by the NES, which are generated chiefly from administrative records of the IRS. These data are primarily composed of sole proprietorship businesses filing IRS Form 1040, Schedule C (Ref. 22). Many of the nonemployer businesses are very small, and many are not the primary source of income for their owners. Furthermore, nonemployers account for 75 percent of all businesses.

· Document in the asset inventory · Document in the SSP. · Document in the network diagram of the CMMC Assessment Scope. · Prepare to be assessed against CMMC security requirements. · Review the SSP: i. If sufficiently documented, do not assess against other CMMC security requirements, except as noted. ii. If OSA's risk-based security policies, procedures, and practices documentation or other findings raise questions about these assets, the assessor can conduct a limited check to identify deficiencies. iii. The limited check(s) shall not materially increase the assessment duration nor the assessment cost. iv. The limited check(s) will be assessed against CMMC security requirements. Specialized Assets · Assets that can process, store, or transmit CUI but are unable to be fully secured, including: Internet of Things (IoT) devices, Industrial Internet of Things (IIoT) devices, Operational Technology (OT), Government Furnished Equipment (GFE), Restricted Information Systems, and Test Equipment · Document in the asset inventory · Document in the SSP. · Show these assets are managed using the contractor's risk-based security policies, procedures, and practices. · Document in the network diagram of the CMMC Assessment Scope. · Review the SSP. · Do not assess against other CMMC security requirements. · Assets that are not in the Level 2 CMMC Assessment Scope Out-of-Scope Assets · Assets that cannot process, store, or transmit CUI; and do not provide security protections for CUI Assets · Prepare to justify the inability of an Out-of-Scope Asset to store, process, or transmit CUI · None. · Assets that are physically or logically separated from CUI assets · Assets that fall into any in-scope asset category cannot be considered an Out-of-Scope Asset (2) If the OSA utilizes an External Service Provider (ESP), other than a Cloud Service Provider (CSP), the ESP must have a CMMC Level 2 Final Certification Assessment. If the ESP is internal to the OSA, the security requirements implemented by the ESP should be listed in the OSA's SSP to show connection to its in-scope environment. In the CMMC Program, CUI or Security Protection Data (e.g., log data, configuration data), must be processed, stored, or transmitted on the ESP assets to be considered an ESP. If using a CSP for Level 2 Self-Assessment, see §.170.16(c)(2). If using a CSP for Level 2 Certification Assessment, see §.170.17(c)(5). (d) CMMC Level 3 scoping. Prior to performing a Level 3 CMMC assessment, the CMMC Assessment Scope must be specified. (1) The CMMC Assessment Scope for Level 3 is based on the specification of asset categories and their respective requirements as set forth in table 2 to this paragraph. Additional information is available in the guidance document listed in paragraph (g) of appendix A to this part. Table 2 to §.170.19(d)(1)-CMMC Level 3 Asset Categories and Associated Requirements

Asset category	Asset description	OSC requirements	CMMC assessment requirements
----------------	-------------------	------------------	------------------------------

administrative, physical, and technical safeguards of the Security Rule. The Department relied on data from AHRQ and the U.S. Census to estimate the number of firms offering group health plans (1.9 million), [958] and multiplied that by the percentage that offer at least one self-insured plan to calculate the number of plan sponsors that would be likely to receive ePHI and be subject to the requirements of 45 CFR 164.314(b) [1,943,484 × .382 = 742,411]. We solicit comments on whether group health plans or third-party administrators address any Security Rule requirements for plan sponsors, so the plan sponsors would not have an additional burden or would have a smaller burden

than estimated below. **Individuals Affected** The number of individuals potentially affected by the proposed changes to the Security Rule includes most of the United States population (approximately 337 million), specifically those who have received any health care in the past seven years and whose ePHI is likely created, received, maintained, or transmitted by a regulated entity. Statistics about the number of individuals affected by breaches of PHI provide insight into known instances where safeguards were breached, although the effects of the Security Rule extend farther than that, to all ePHI. Data from the 2022 Annual Report to Congress on Breaches of Unsecured Protected Health Information for Calendar Year 2022 [959] revealed nearly 42 million individuals affected by breaches of PHI in that year. Third-party sources reported approximately 133 million individuals affected by health care breaches in 2023. [960] According to UnitedHealth Group, the 2024 breach of its clearinghouse subsidiary Change Healthcare may have affected approximately one-third of the U.S. population, or 112 million individuals. [961] The Department believes that the range of individuals potentially affected by the proposed regulatory changes would be from 42 million to 337 million. **HIPAA Breach Data** The Department has reported HIPAA/HITECH breach data annually since 2009. Table 5 shows the data as reported to Congress for the past five years. We relied on this data, combined with breach cost data from industry sources, to analyze the potential savings of the NPRM. **Table 5-Breaches of PHI**

Year	Small breaches (fewer than 500 affected individuals)	Large breaches (500+ affected individuals)	Total Breach count	Affected individuals
2018	63,098	296,948	302	12,196,601
2019	63,400	12,493,549	62,771	284,812
2020	408	38,732,966	63,179	39,017,778
2021	609	37,182,558	64,180	37,501,773
2022	626	41,747,613	64,592	42,004,718

3. Costs of the Proposed Rule

(A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation or prosecutable interest by the NGA or other agencies. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence. (B) From subsections (d) and (f) because providing access to investigative records and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that (printed page 14782) would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because this system of records is compiled for investigative purposes and is exempt from the access provisions of subsections (d) and (f). (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NGA will, nevertheless, continue to publish such a notice in broad generic terms, as is its current practice.

MA.L2-3.7.3 · Equipment Sanitization CMMC Assessment Guide · Level 2 | Version 2.13 148
 MA.L2-3.7.3 · EQUIPMENT SANITIZATION Ensure equipment removed for off-site maintenance is sanitized of any CUI. **ASSESSMENT OBJECTIVES** [NIST SP 800-171A]130 Determine if: [a] equipment to be removed from organizational spaces for off-site maintenance is sanitized of any CUI. **POTENTIAL ASSESSMENT METHODS AND OBJECTS** [NIST SP 800-171A]130 Examine [SELECT FROM: System maintenance policy; procedures addressing controlled system maintenance; maintenance records; manufacturer or vendor maintenance specifications; equipment sanitization records; media sanitization records; system security plan; other relevant documents or records]. Interview [SELECT FROM: Personnel with system maintenance responsibilities; personnel with information security responsibilities;

personnel responsible for media sanitization; system or network administrators]. Test [SELECT FR OM: Organizational processes for scheduling, performing, documenting, reviewing, approving, and monitoring maintenance and repairs for systems; organizational processes for sanitizing system components; mechanisms supporting or implementing controlled maintenance; mechanisms implementing sanitization of system components]. DISCUSSION [NIST SP 800-171 REV. 2]131 This requirement addresses the information security aspects of system maintenance that are performed off- site and applies to all types of maintenance to any system component (including applications) conducted by a local or nonlocal entity (e.g., in- contract, warranty, in-house, software maintenance agreement). NIST SP 800-88 provides guidance on media sanitization. FURTHER DISCUSSION Sanitization is a process that makes access to data infeasible on media such as a hard drive. The process may overwrite the entire media with a fixed pattern such as binary zeros. In 130 NIST SP 800-171A, p. 39. 131 NIST SP 800-171 Rev. 2, p. 28.

The DoD has included the numbering scheme in the rule because the numbering scheme is a key element of the model. The CMMC numbering scheme for security requirements must pull together the independent numbering schemes of FAR clause 52.204-21 (for Level 1), NIST SP 800-171 R2 (for Level 2), and NIST SP 800-172 Feb2021 (for Level 3); it must also identify the domain and CMMC level of the security requirement. DoD developed the least complicated scheme that met all these criteria. The CMMC Program Office is unable to respond to comments proposing changes to the DFARS, which is subject to separate rulemaking procedures. One commenter described a hypothetical scenario wherein a solicitation is issued such that DFARS clause 252.204-7012 would require compliance with NIST SP 800-171 Revision 3, but the CMMC requirement identified is for assessment against NIST SP 800-171 R2. In this hypothetical scenario, it is possible that the bidder may meet the CMMC requirement by citing a valid CMMC assessment against NIST SP 800-171 R2, while also availing themselves of the flexibilities provided in DFARS clause 252.204-7012 (2)(ii)(B) to submit a written request to the Contracting Officer to vary from the current version of NIST SP 800-171. Recommendations for modification to or deviation from DFARS clause 252.204-7012 are beyond the scope of this rule. The DoD has evaluated the potential interaction between the CMMC program requirements and the existing requirements in DFARS clause 252.204-7012 and believes that potential conflicts have been resolved. NIST SP 800-53 R5 is incorporated by reference only for applicable definitions because DoD chose to use the latest definitions available. While it is also true that NIST SP 800-171 R2 was based on NIST SP 800-53 Revision 4, the origination of NIST SP 800-171 R2 is beyond the scope of this rule. Contractors and subcontractors will not be expected to stop work while they implement changing standards. Implementation of this rule will be introduced as a pre-award requirement in new DoD solicitations, as described in the timeline at § 170.3(e). Any substantive change to CMMC security requirements must go through rulemaking, and its associated timeline, which may include public comment. The new rule may include a transition period for implementation of the new security requirements. The commenter correctly identifies that the programmatic intent of this rule is for affirmations to signify systems in question remain compliant as indicated by the assessment that was conducted. Assessments are conducted against the specified NIST publication versions or the requirements in FAR clause 52.204-21. The 48 CFR part 204 CMMC Acquisition rule also reinforces this thought by providing specific wording of the affirmation. c. NIST SP 800-172 Feb2021 Requirements Comment:

The CMMC requirements established pursuant to DFARS Case 2019-D041 have not been revised as of the date of publication of this final rule. However, the CMMC Program requirements in this final rule will be implemented in the DFARS, as needed, which may result in changes to the current DFARS text, solicitation provisions, and contract clauses relating to DoD's cybersecurity protection requirements, including DFARS subpart 204.75 and DFARS clause 252.204-7021, Cybersecurity Maturity Model Certification (CMMC) Requirements. Context of the CMMC Program in Light of Other DoD-Related Work At present, and prior to the DFARS CMMC Acquisition rule becoming effective, the Department is using the DCMA DIBCAC to conduct CMMC Level 2-like assessments. To date, the DCMA DIBCAC has assessed 357 entities including DoD's major prime contractors. The CMMC Program's assessment phase- in plan, as described in § 170.3 Applicability, does not preclude entities from immediately and voluntarily seeking a CMMC certification assessment prior to the DFARS CMMC Acquisition rule being finalized and the clause being added to new or existing DoD contracts. The Department estimates 8,350 medium and large entities will require CMMC Level 2 certification assessments. Once the CMMC DFARS coverage is effective, the Department will contractually mandate CMMC Level (printed page 83171) 2 certification assessments on these entities. It is estimated that 135 CMMC Third-Party Assessment Organization (C3PAO)-led assessments will be completed in the first year. The Department

estimates 673 C3PAO-led assessments in year 2 followed by 2,252 C3PAO-led assessments in year 3. During the fourth year, the Department estimates 4,452 C3PAO-led assessments will be completed. The DCMA DIBCAC will perform assessments upon DoD's request. Additionally, the Department may include CMMC Level 2 certification requirements on contracts awarded prior to the CMMC DFARS coverage becoming effective, but doing so will require bilateral contract modification after negotiations. The CMMC Program has been incorporated in the Department's 2024 Defense Industrial Base Cybersecurity Strategy. [28] The strategy requires the Department to coordinate and collaborate across components to identify and close gaps in protecting DoD networks, supply chains, and other critical resources. Other prongs of the Department's cybersecurity strategy are described in the Department's National Industrial Security Program Operating Manual (NISPOM) which address implementation of the Security Executive Agent Directive (SEAD) 3, [29] including clarifications on procedures for the protection and reproduction of classified information; controlled unclassified information (CUI); National Interest Determination (NID) requirements for cleared contractors operating under a Special Security Agreement for Foreign Ownership, Control, or Influence; and eligibility determinations for personnel security clearance processes and requirements. [30]

Back to Citation 900. · Julia Adler-Milstein, et al., · Next-Generation Artificial Intelligence for Diagnosis: From Predicting Diagnostic Labels to 'Wayfinding,' · Journal of the American Medical Association (Dec. 9, 2021), <https://jamanetwork-com.hhsnih.idm.oclc.org/journals/jama/fullarticle/2787207> . Back to Citation 901. Id. Back to Citation 902. · See Letter from NCVHS Chair Jacki Monson (2023), *supra* note 123, Appendix p. 8 (providing NCVHS recommendations to strengthen the HIPAA Security Rule); see also William Dixon, et al., · 3 ways AI will change the nature of cyber attacks, · World Economic Forum (June 19, 2019), <https://www.weforum.org/agenda/2019/06/ai-is-powering-a-new-generation-of-cyberattack-its-also-our-best-defence/> . Back to Citation 903. · 3 ways AI will change the nature of cyber attacks, · *supra* note 902. Back to Citation 904. Id. Back to Citation 905. Id. Back to Citation 906. Id. Back to Citation 907. · Where a regulated entity is maintaining ePHI for research purposes as described by 45 CFR 164.512(i) , the regulated entity is not performing a covered function. Back to Citation 908. · See Jordan Pearson, · ChatGPT Can Reveal Personal Information From Real People, Google Researchers Show, · Vice (Nov. 29, 2023), <https://www.vice.com/en/article/chatgpt-can-reveal-personal-information-from-real-people-google-researchers-show/> ; see also Bridget McArthur, · AI chatbot blamed for psychosocial workplace training gaffe at Bunbury prison, · ABC Southwest (Aug. 20, 2024), <https://www.abc.net.au/news/2024-08-21/ai-chatbot-psychosocial-training-bunbury-regional-prison/104230980> . Back to Citation 909. · See Nick Easen, · Why generative AI presents a fundamental security risk, · Raconteur (Sept. 9, 2024), <https://www.raconteur.net/technology/why-generative-ai-presents-a-fundamental-security-threat> . Back to Citation 910. · See 45 CFR 164.308(a)(1)(ii)(A) and (B) ; proposed 45 CFR 164.308(a)(2)(i) and (a)(5)(i) . Back to Citation 911. · Artificial Intelligence Risk Management Framework, (AI RMF 1.0), · NIST AI 100-1, National Institute of Standards and Technology, U.S. Department of Commerce (Jan. 2023), <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf> ; see also · Joint Guidance on Deploying AI System Securely, · Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security (Apr. 15, 2024), <https://www.cisa.gov/news-events/alerts/2024/04/15/joint-guidance-deploying-ai-systems-securely> . Back to Citation 912. 45 CFR 164.508 . Back to Citation 913. · See Letter from NCVHS Chair Jacki Monson (2023), *supra* note 123, Appendix p. 8. Back to Citation 914. 88 FR 75191 (Nov. 1, 2023). Back to Citation 915. Id. Back to Citation 916. 89 FR 1192 (Jan. 9, 2024). Back to Citation 917. Id. Back to Citation

The DDN Management Bulletin is distributed electronically by the Defense Data Network (DDN) Network Information Center under contract to the Defense Communications Agency. It is a means of communicating official policy, procedures, and other information of concern to management personnel at DDN facilities. The DDN Security Bulletin is distributed electronically by the DDN SCC (Security Coordination Center), also under contract to DCA, as a means of communicating information on network and host security exposures, fixes, and concerns to security and management personnel at DDN facilities.

(vi) The dispatching contractor will prepare three copies of a receipt based on the inventory and list the classified material that is being sent. The dispatching contractor will retain one copy of the receipt. The contractor will pack the other two copies with the classified material. The

contractor will obtain a receipt for the sealed package from the courier. (vii) The dispatching contractor will provide the receiving contractor with 24 work hours advance notification of the anticipated date and time of the courier's arrival and the identity of the courier. The receiving contractor must notify the dispatching contractor if the courier does not arrive within 8 hours of the expected time of arrival. The dispatching contractor will notify its DGR of any delay, unless officially notified otherwise of a change in the courier's itinerary. (printed page 83352)

(viii) The receiving DGR will verify the contents and sign the receipts enclosed in the consignment. The receiving DGR will return one copy to the courier. On return, the courier will provide the executed receipt to the dispatching contractor. (ix) Throughout the journey, the courier will maintain the classified material under direct personal control. The courier will not leave the material unattended at any time during the journey, in the transport being used, in hotel rooms, in cloakrooms, or other such location, and will not deposit it in hotel safes, luggage lockers, or in luggage offices. In addition, the courier will not open envelopes or packages containing the classified material en route, unless required by customs or other government officials. (x) When inspection by government officials is unavoidable, the courier will request that the officials provide written verification that they have opened the package. The courier will notify their employing contractor as soon as possible. The contractor will notify the U.S. DGR. If the inspecting officials are not of the same country as the dispatching contractor, the CSA will notify the designated security authority in the country whose officials inspected the consignment. Under no circumstances will the courier hand over the classified material to customs or other officials for their custody. (xi) When carrying classified material, the courier will not travel by surface routes through third countries, except as authorized by the CSA. The courier will travel only on carriers described in paragraph (d)(2)(iv) in this section, and will travel direct routes between the United States and the destination. (7) Classified material receipts. (i) The U.S. DGR and the DGR of the ultimate foreign recipient will maintain a continuous chain of receipts to record international transfers of all classified material from the contractor through the dispatching DGR and recipient DGR to the ultimate foreign recipient. The dispatching contractor will retain: (A) An active suspense record until return of applicable receipts for the material.

Roles and responsibilities of the CMMC PMO, the Accreditation Body, and its organizations are described in SUBPART C of this rule. The Accreditation Body accredits C3PAOs and the CAICO. The Accreditation Body authorizes the CAICO to certify CMMC assessors and instructors and the C3PAOs to conduct assessments using CAICO-certified assessors. Comment: Many commenters expressed concerns about how to ensure the necessary independence, quality assurance, integrity, and rigor of, and protection against potential conflicts of interest within the Accreditation Body and C3PAOs. Numerous commenters recommended the use of ISO/IEC standards to address these issues. Additionally, one commenter was concerned about high costs for assessments that could result if there is a lack of oversight for charging fees. Response: The Accreditation Body is required to become compliant with the ISO/IEC 17011:2017 standard (the international benchmark used in demonstrating an accreditation body's impartiality, technical competency, and resources) and the requirements set forth in §.170.8. Additionally, the C3PAOs and CAICO must comply with requirements as specified in §.170.9 and §.170.10, respectively, including the specified ISO/IEC standards. Comment: To address a perceived shortage of CMMC C3PAO assessors, two commenters suggested authorizing the use of other ISO/IEC-compliant accreditation bodies to increase the numbers of assessors. Another commenter wanted to know how a company could become an accreditation body. Response: Consistency in training is imperative due to the unique qualifications needed to understand requirements. Additionally, ISO/IEC 17024:2012 Conformity Assessment requirements are levied against the CAICO and may not be required by other entities. The number and level of assessors needed is relative to the number of companies seeking CMMC assessment. The demand level is influenced, but not solely determined by, the number of solicitations that include CMMC requirements, the CMMC Levels specified, and the estimated number of subcontractors that will also need to meet CMMC requirements, when flowed down by the prime contractor. To facilitate a smooth and orderly transition to CMMC, the Department will issue policy guidance to government Program Managers to govern the rate at which CMMC requirements are levied in new solicitations. The implementation phases are described in §.170.3(e). The CMMC PMO has visibility into the Accreditation Body's assessor training activities, tracks the anticipated number of trained assessors, and will use this information to inform policies that guide government Program Managers in identifying CMMC requirements in new solicitations. 23. Relationship to Existing Regulations Comment:

(ii) For litigation support contractors accessing litigation information, including that originating

from third parties, use and non-disclosure requirements are addressed through the use of the clause at 252.204-7014, as prescribed at 204.7403(a). Pursuant to the clause, litigation support contractors are not required to enter into non-disclosure agreements directly with any third party asserting restrictions on any litigation information. PART 212·ACQUISITION OF COMMERCIAL ITEMS 212.301 [Amended] 4. Amend section 212.301 by· a. Removing paragraph (f)(ii)(E); b. Redesignating paragraphs (f)(ii)(F) and (G) as paragraphs (f)(ii)(E) and (F), respectively; c. In the newly redesignated (f)(ii)(E) removing ·204.7403(b)· and adding ·204.7403(a)· in its place; and d. In the newly redesignated (f)(ii)(F) removing ·204.7403(c)· and adding ·204.7403(b)· in its place. PART 252·SOLICITATION PROVISIONS AND CONTRACT CLAUSES 252.204-7013 [Removed and Reserved] 5. Remove and reserve section 252.204-7013. 252.204-7014 [Amended] 6. Amend section 252.204-7014, in the introductory text, by removing ·204.7403(b)· and adding ·204.7403(a)· in its place. 252.204-7015 [Amended] 7. Amend section 252.204-7015, in the introductory text, by removing ·204.7403(c)· and adding ·204.7403(b)· in its place. [FR Doc. 2019-23802 Filed 10-30-19; 8:45 am] BILLING CODE 5001-06-P

DoD, GSA, and NASA seek responses to any or all the questions that follow this paragraph. Where possible, include specific examples of how your organization is or would be impacted negatively or positively by the recommended scope and subparts; if applicable, provide rationale supporting your position. If you believe the proposed scope and subparts should be revised, suggest an alternative (which may include not providing guidance at all) and include an explanation, analysis, or both, of how the alternative might meet the same objective or be more effective. Comments on the economic effects including quantitative and qualitative data are especially helpful. In addition to the FAR parts and subparts proposed for relocation to FAR part 40, let us know: 1. What specific section(s) of the FAR would benefit from inclusion in FAR part 40? 2. What specific suggestions do you have for otherwise improving the proposed scope or subparts of FAR part 40? William F. Clark, Director, Office of Government-wide Acquisition Policy, Office of Acquisition Policy, Office of Government-wide Policy. [FR Doc. 2024-07535 Filed 4-9-24; 8:45 am] BILLING CODE 6820-EP-P

A purpose of the phased implementation is to ensure adequate availability of authorized or accredited C3PAOs and assessors to meet the demand. CMMC 2.0·Flow Down CMMC Level requirements will be flowed down to subcontractors at all tiers as set forth in 32 CFR 170.23 ; however, the specific CMMC Level required for a subcontractor will be based on the type of unclassified information and the priority of the acquisition program and/or technology being developed. Key Changes Incorporated in the CMMC 2.0 Program In November 2021, the Department announced ·CMMC 2.0,· which is an updated program structure with revised requirements. In CMMC 2.0, the Department has introduced several key changes that build on and refine the original program requirements. These include: Streamlining the model from five levels to three levels. Exclusively implementing National Institute of Standards and Technology (NIST) cybersecurity standards and guidelines. Allowing all companies subject to Level 1, and a subset of companies subject to Level 2 to demonstrate compliance through self-assessments. Increased oversight of professional and ethical standards of CMMC third-party assessors. Allowing Plans of Action & Milestones (POA&M) under limited circumstances to achieve conditional certification. As a result of the alignment of CMMC 2.0 to NIST guidelines, the Department's requirements will continue to evolve as changes are made to the underlying NIST SP 800-171 Rev 2 and NIST SP 800-172 requirements. CMMC Assessment Assessment Criteria CMMC requires that defense contractors and subcontractors entrusted with FCI and CUI implement cybersecurity standards at progressively more secure levels, depending on the type and sensitivity of the information. CMMC Level 1 Self-Assessment An annual CMMC Level 1 Self-Assessment and annual affirmation asserts that an OSA has implemented all the Basic Safeguarding requirements to protect FCI as set forth in 32 CFR 170.14(c)(2) . An OSA can choose to perform the annual self-assessment internally or engage a third-party to assist with evaluating its Level 1 compliance. Use of a third party to assist with the (printed page 89084) assessment process is still considered a self-assessment and does not result in a CMMC certification. An OSA can be compliant with CMMC Level 1 requirements for an entire enterprise network or for a particular enclave(s), depending upon where the FCI is or will be processed, stored, or transmitted. CMMC Level 2 Self-Assessment A CMMC Level 2 Self-Assessment and triennial affirmation attests that an OSA has implemented all the security requirements to protect CUI as specified in 32 CFR 170.14(c)(3) . CMMC Level 2 Certification Assessment A CMMC Level 2 Certification Assessment, conducted by a C3PAO, verifies that an OSC is conforming to the security requirements to protect CUI as specified in 32 CFR 170.14(c)(3)

-----| | [BXANL] | Bouras MA, Xia B, Abuassba AO, Ning H, Lu Q (2021) IoT-CCAC: A Blockchain-Based Consortium Capability Access Control Approach for IoT. PeerJ Computer Science 7:e455. <https://doi.org/10.7717/peerj-cs.455> | | [DMMR] | Di Francesco Maesa D, Mori P, Ricci L (2019) A Blockchain Based Approach for the Definition of Auditable Access Control Systems. Computers & Security 84(July):93-119. <https://doi.org/10.1016/j.cose.2019.03.016> | | [GBHC] | Ghaffari F, Bertin F, Hatin J, Crespi N (2020) Authentication and Access Control Based on Distributed Ledger Technology: A survey. 2nd conference on Blockchain Research & Applications for Innovative Networks and Services (BRAINS 2020) (IEEE, Paris), pp 79-86. <https://doi.org/10.1109/BRAINS49436.2020.9223297> | | [GMS] | Guo H, Meamari E, Shen CC (2019). Multi-Authority Attribute-Based Access Control with Smart Contract. Proceedings of the 2019 International Conference on Blockchain Technology (ICBCT 2019) (ACM, Honolulu, Hawai'i), pp 6-11. <https://doi.org/10.1145/3320154.3320164> | | [GPR] | Gusmeroli S, Piccione S, Rotondi D (2013) A Capability-Based Security Approach to Manage Access Control in the Internet of Things. Mathematical and Computer Modelling 58(5-6), pp 1189-1205 . <https://doi.org/10.1016/j.mcm.2013.02.006> | | [GT] | Grant Thornton US (2020) Blockchain and Privacy: How Do You Protect Data That's Distributed?[video].

There were numerous comments regarding Contractor Risk Managed Assets. Several comments perceived conflicts in the changes between the current rule and previous intermediate documents regarding CRMA requirements. Multiple comments recommended additional details explaining risk-based management of assets. Two comments requested additional details on the limited checks that are permitted during assessment of CRMAs. Multiple comments requested clarification on CRMA requirements at Level 3 for the OSA and ESP. One comment requested clarification about the documentation requirements for CRMAs. One comment asserted that the rule co-mingled CRMAs with assets of an ESP. One comment questioned why CRMAs were being included as in-scope assets subject to CMMC security requirements. One comment asked for clarification between the security requirements and assessment requirements for CRMAs. Response: There was confusion and concern over conflicts from commenters regarding responses to comments on a previous version of the rule, other documentation, and the current rule. The DoD did not find any conflicting language around CRMAs. There is no conflict between CRMAs and the requirements for logical or physical boundaries. CRMAs are only applicable within the CMMC Assessment Scope. DoD does not agree with the statement that the wording change around Contractor Risk Managed Asset (CRMA) effectively makes the asset category moot. The CRMA category was created to ease the assessment burden, based on the Department's risk tolerance. It is not intended to reduce the level of protection and the CMMC security requirements which apply to the assets. Despite the wording changes identified by the commentor, the CMMC security requirements and the assessor's ability to conduct a limited check to identify deficiencies as addressed in table 3 to § 170.19(c)(1) are unchanged. Contractor Risk Managed Assets (CRMA) should be prepared to be assessed against CMMC security requirements at Level 2, and included in the SSP, asset inventory, and network diagrams. Table 3 to § 170.19(c)(1) clearly addresses the assessment requirements for Contractor Risk Managed Assets. All CMMC security requirements must be MET when the OSA chooses to designate certain assets as Contractor Risk Managed Assets. Eight guidance documents for the CMMC Program are listed in Appendix A to Part 170-Guidance. These documents provide additional guidance for the CMMC model, assessments, scoping, and hashing. Use of the guidance documents is optional.

The Department has explained in regulation and guidance the difference between required and addressable implementation specifications. The meaning of 'required' is clear. Regarding 'addressable,' we previously explained that its purpose is to provide regulated entities flexibility with respect to implementation compliance. [414] We also previously explained that a regulated entity must assess whether a given addressable implementation specification is a reasonable and appropriate security measure to apply within its environment, and if it is, the regulated entity must implement the addressable implementation specification. [415] However, the Department remains concerned that regulated entities believe that flexibility overrides the need for them to protect all ePHI and do not uniformly treat addressable implementation specifications as needing to be met if they are reasonable and appropriate. OCR's enforcement experience and interaction with regulated entities causes us to believe that 'addressable' is misunderstood to be optional, leading regulated entities to choose not to adopt the implementation specification, even when it would be reasonable and appropriate for them to do so. [416] In 2022, NCVHS recommended that the Department eliminate the choice to not implement a specification or alternative, and instead require that regulated entities implement the specification or adopt a documented reasonable alternative. [417] According to a survey referenced by NCVHS, despite private sector and government efforts to address a changing cybersecurity landscape, the majority of health care entities have failed to

maintain a comprehensive security program and (printed page 932) continue to neglect people and process measures necessary for a comprehensive security program. [418] NCVHS also pointed to a continued failure of regulated entities to develop adequate incident recovery plans and to assess their vulnerability to cyberattacks grounded in social engineering. [419] Finally, NCVHS opined that the current structure of the Security Rule is inadequate to protect U.S. health care infrastructure because it does not require regulated entities to adopt the basic building blocks of good security hygiene, or a documented, reasonable alternative. [420] We share NCVHS' concerns and believe that we must squarely confront the problem of regulated entities treating addressable implementation specifications as optional. Relatedly, we also believe that we must consider modifying the Security Rule to set an acceptable minimum level of security specifications. Circumstances have changed sufficiently since 2003 such that we now believe that good cyber hygiene requires regulated entities to implement more than the implementation specifications that we originally mandated. [421] Indeed, we believe that it requires compliance with all of the standards and implementation specifications we are proposing, with specific, limited exceptions.

(F) Review, biennially, recordkeeping practices to ensure compliance with the Act, paying particular attention to the maintenance of automated records. In addition, ensure cooperation with records management officials on such matters as maintenance and disposal procedures, statutory requirements, forms, and reports; and (G) Review, biennially Privacy Act training practices. This is to ensure all personnel are familiar with the requirements of the Act. (6) DA Privacy Act System Managers and Developers will-

- (i) Ensure that appropriate procedures and safeguards are developed, implemented, and maintained to protect an individual's personal information;
- (ii) Ensure that all personnel are aware of their responsibilities for protecting personal information being collected and maintained under the Privacy Act Program;
- (iii) Ensure official filing systems that retrieve records by name or other personal identifier and are maintained in a Privacy Act system of records have been published in the Federal Register as a Privacy Act system of records notice. Any official who willfully maintains a system of records without meeting the publication requirements, as prescribed by 5 U.S.C. 552a, as amended, OMB Circular A-130, 32 CFR part 310 and this part, will be subject to possible criminal penalties and/or administrative sanctions;
- (iv) Prepare new, amended, or altered Privacy Act system of records notices and submit them to the DA Freedom of Information and Privacy Office for review. After appropriate coordination, the system of records notices will be submitted to the Defense Privacy Office for their review and coordination;
- (v) Review, biennially, each Privacy Act system of records notice under their purview to ensure that it accurately describes the system of records;
- (vi) Review, every four years, the routine use disclosures associated with each Privacy Act system of records notice in order to determine if such routine use continues to be compatible with the purpose for which the activity collected the information;
- (vii) Review, every four years, each Privacy Act system of records notice for which the Secretary of the Army has (printed page 46054) promulgated exemption rules pursuant to Sections (j) or (k) of the Act. This is to ensure such exemptions are still appropriate;
- (viii) Review, every year, contracts that provide for the maintenance of a Privacy Act system of records to accomplish an activity's mission. This requirement is to ensure each contract contains provisions that bind the contractor, and its employees, to the requirements of 5 U.S.C. 552a(m)(1) ; and

Currently, the DIB CS Program has approximately 1,000 cleared defense contractors participating in the program. Program participants have access to technical exchange meetings, a collaborative web platform (DIBNet-U), and threat products and services through the DoD Cyber Crime Center (DC3). DC3 implements the program's operations by sharing cyber threat information and intelligence with the DIB, and offering a variety of products, tools, services, and events. DC3 serves as the single clearinghouse for unclassified Mandatory Incident Reports (MIRs) and voluntary threat information sharing reports. Changes to Definitions In addition to the program eligibility changes described above, DoD is also proposing the following changes. § 236.2-Definitions 1. Access to media-This definition is being removed as it is no longer used in the rule text. 3. DIB CS Program participant-This definition has been revised to align with the revised eligibility requirements set forth in this proposed rule. 4. Government furnished information (GFI)-This definition was revised to adopt the convention of referring to the DIB CS Program with a capital 'P'. Other Proposed Changes DoD is amending § 236.5 (DoD's DIB CS program) in order to align the program description with the revised eligibility requirements. As a result, references to cleared defense contractors have been replaced with contractors that own or operate a covered contractor information system. Security clearance information is only collected, when applicable, if a company elects to participate in classified information sharing. In addition, the language stating participation is

typically three to ten company-designated points of contact (POC) has been removed, to avoid confusion regarding the number of POCs, as some larger companies may wish to nominate a larger number of (printed page 27834) POCs and smaller companies may wish to nominate fewer. DoD is amending § 236.7 (DoD's DIB CS program requirements) to remove the requirement that a company have an existing active facility clearance (FCL) to at least the Secret level granted under 32 CFR part 117 , National Industrial Security Program Operating Manual (NISPOM), [12] to be eligible to participate in the DIB CS Program. In addition, references to cleared defense contractors have been replaced with contractors that own or operate a covered contractor information system. A foundational element of the activities described in this part is the recognition that the information shared between DoD and DIB CS Program participants pursuant to the DIB CS Program includes extremely sensitive information that requires protection. For additional information regarding the Government's safeguarding of information received from contractors that requires protection, see the Privacy Impact Assessment (PIA) for the DIB Cybersecurity Activities located at: https://dodcio.defense.gov/Portals/0/Documents/DIB_PIA.pdf .

From the NIST SP 800-172 Rev 3 Final Public Draft: component See system component . NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 c confidentiality 2852

(4) The requester shall be given access to any deletions or changes to records that are accessible.

(e) Access to Medical Records. (1) Medical records and other protected health information (PHI) shall be disclosed to the individual pursuant to Chapter 11 of DoD 6025.18-R, DoD Health Information Privacy Regulation (Available at <http://www.dtic.mil/whs/directives/corres/pdf/602518r.pdf>) and 32 CFR part 310, subpart D . (2) The individual may be charged reproduction fees for copies or records as outlined in 32 CFR part 310, subpart D . (f) Amending and Disputing Personal Information in Systems of Records. (1) The System Manager shall allow individuals to request amendments to the records covered by their system notice to the extent that such records are not accurate, relevant, timely, or complete. Amendments are limited to correcting factual matters and not matters of official judgment, such as performance ratings, promotion potential, and job performance appraisals. (2) Individuals seeking amendment to records that pertain to themselves, and that are filed or retrieved by their name or other personal identifier, may submit a request for amendment in person, by mail, or by email. All requests for amendment must be in accordance with the following: (i) Any individual making a request for amendment to records in person shall show personal identification to the appropriate System Manager, as identified in the SORN published in the FR, to verify his or her identity, as outlined in 32 CFR part 310, subpart D . (ii) Any individual making a request for amendment to records by mail or email shall address such request to the System Manager. If the System Manager is unknown, they may inquire to NGB-JA/OIP: AHS-Bldg 2, Suite T319B, 111 S. George Mason Drive, Arlington VA 22204-1382, or email privacy@ng.army.mil for assistance in locating the System Manager. (iii) Requests for amendment shall include a mailing address where the decision on the request for amendment can be sent and include either a signed notarized statement or a signed unsworn declaration to verify his or her identity to ensure that they are seeking to amend records about themselves and not, inadvertently or intentionally, the records of others. The Privacy Act (5 U.S.C. 552a) provides a penalty of a misdemeanor and a fine of not more than \$5,000 for any person who knowingly and willfully requests or obtains any record concerning an individual from an agency under false pretenses. The declaration shall read as follows: (A) Inside the US: I declare (or certify, verify, or state) under penalty of perjury that the foregoing is true and correct. Executed on (date). (Signature). (B) Outside the US: I declare (or certify, verify, or state) under penalty of perjury under the laws of the United States of America that the foregoing is true and correct. Executed on (date). (Signature).

includes that contractors must submit reports pursuant to this rule, SEAD 3 and CSA guidance to supplement unique CSA mission requirements. SEAD 3 reporting establishes a single nationwide implementation plan for covered individuals, which for this rule provides reporting by contractors and their employees eligible for access to classified information. SEAD 3 requirements will be implemented for all contractor cleared personnel to report specific activities that may adversely impact their continued national security eligibility. Contractor cleared personnel must be aware of risks associated with foreign intelligence operations and/or possible terrorist activities directed against them in the United States and abroad, and have a responsibility to recognize and avoid personal behaviors and activities that adversely affect their national security eligibility. NISP CSAs shall conduct an analysis of such reported activities, such as foreign travel or foreign

contacts, to determine whether they pose a potential threat to national security and take appropriate action. Contractors will be responsible for collecting the foreign travel data from cleared employees, providing pre- and post-travel briefings to those cleared employees when necessary, and tracking and reporting those foreign travel activities of its cleared employees through the CSA designated system of record for personnel security clearance data. § 117.9(m) Limited entity eligibility determination (Non-FOCI) and, § 117.11(e) Limited entity eligibility determination due to FOCI. In accordance with 32 CFR part 2004, NISP Directive, provisions for granting two new types of limited entity facility clearance eligibility determinations (FCLs) to meet government requirements for narrowly scoped requirements for a companies to access classified information. § 117.11(d)(2)(iii)(A) Requirement for National Interest Determinations (NIDs): This paragraph provides for the implementation of the provisions of Section 842 of Public Law 115-232, which was effective on October 1, 2020, and eliminates requirements for a covered NTIB entity operating under an SSA to obtain a NID for access to proscribed information: Top Secret, Special Access Program, Communications Security, Sensitive Compartmented Information, and Restricted Data. This provision will allow covered NTIB entities to begin performing on contracts that require access to proscribed information without having to wait on a NID, and thus removing costly contract performance delays. § 117.15(e)(2) TOP SECRET Information: Permits specific determinations by a CSA with respect to requirements for TOP SECRET accountability (e.g.,

(k) The Deputy Chief of Staff, G-1 is authorized to act on the following records: Personnel board records, Equal Opportunity (military) and sexual harassment, health promotions, physical fitness and well being, command and leadership policy records, HIV and suicide policy, substance abuse programs except for individual treatment records which are the responsibility of the Surgeon General, retiree benefits, services, and programs (excluding individual personnel records of retired military personnel, which are the responsibility of the U.S. Army Human Resources Command-St. Louis), DA dealings with Veterans Affairs, U.S. Soldier's and Airmen's Home; all retention, promotion, and separation records; all military education records including records related to the removal or suspension from a military school or class; Junior Reserve Officer Training Corps (JROTC) and Senior Reserve Officer Training Corps (SROTC) records; SROTC instructor records; U.S. Military Academy Cadet Records; recruiting and MOS policy issues, personnel travel and transportation entitlements, military strength and statistics, The Army Librarian, demographics, and Manprint. (l) The Deputy Chief of Staff, G-4 is authorized to act on requests for records relating to DA logistical requirements and determinations, policy concerning materiel maintenance and use, equipment standards, and logistical readiness. (m) The Chief of Engineers is authorized to act on requests for records involving civil works, military construction, engineer procurement, and ecology; and the records of the U.S. Army Engineer divisions, districts, laboratories, and field operating agencies. (n) The Surgeon General/Commander, U.S. Army Medical Command, is authorized to act on requests for medical research and development records, and the medical records of active duty military personnel, dependents, and persons given physical examination or treatment at DA medical facilities, to include alcohol and drug treatment/test records. (o) The Chief of Chaplains is authorized to act on requests for records involving ecclesiastical relationships, rites performed by DA chaplains, and nonprivileged communications relating to clergy and active duty chaplains' military personnel files. (p) The Judge Advocate General is authorized to act on requests for records relating to claims, courts-martial, legal services, administrative investigations, and similar legal records. The Judge Advocate General is also authorized to act on requests for the General Officer Management Office actions, and records described elsewhere in this part if those records relate to litigation in which the United States has an interest. In addition, The Judge Advocate General is authorized to act on requests for records that are not within the functional areas of responsibility of any other Denial Authority.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analysis to advance the development and productive use of information technology. ITL's responsibilities include the development of technical, physical, administrative, and management standards and guidelines for the cost-effective security and privacy of sensitive unclassified information in Federal computer systems. This Special Publication discusses ITL's research, guidance, and outreach efforts in computer security, and its collaborative activities with industry, government, and academic organizations. The security objectives of an organization are a key factor for decisions about outsourcing information

technology services and, in particular, for decisions about transitioning organizational data, applications, and other resources to a public cloud computing environment. Organizations should take a risk-based approach in analyzing available security and privacy options and deciding about placing organizational functions into a cloud environment. The information technology governance practices of the organizations that pertain to the policies, procedures, and standards used for application development and service provisioning, as well as the design, implementation, testing, use, and monitoring of deployed or engaged services, should be extended to cloud computing environments.

(Response) The final rule applies to persons that manufacture, process, pack, hold, transport, distribute, receive, or import food in the United States. Section 201(a)(1) of the FD&C Act defines the term ‘State’ as, ‘any State or Territory of the United States, the District of Columbia, and the Commonwealth of Puerto Rico’, and section 201(a)(2) of the FD&C Act defines the term ‘Territory’ as, ‘any Territory or possession of the United States, including the District of Columbia, and excluding the Commonwealth of Puerto Rico and the Canal Zone’. Accordingly, any person in the 50 States of the United States, or in any Commonwealth or Territory of the United States, that performs a covered activity is subject to the requirements of this final rule. This includes both Puerto Rico (because, for purposes of the FD&C Act, it is considered a State) and the U.S. Virgin Islands (because, as a U.S. territory, it is considered a State for purposes of the FD&C Act). D. Comments on Who is Excluded From All or Part of the Regulations in This Subpart? (Proposed § 1.327) 1. General (Comment 29) Several comments argue that because the Bioterrorism Act specifically excludes those foods under the jurisdiction of USDA, alcoholic beverages should also be excluded, as they are already regulated by the Department of Treasury’s Alcohol and Tobacco Tax and Trade Bureau (TTB) as well as by CBP. One comment requests that FDA secure a legislative amendment to the Bioterrorism Act that exempts wines and spirits and other alcoholic beverages from its application, in the same way meat, poultry, and egg products under the jurisdiction of the USDA are excluded from its scope. Another comment states that the importer’s records enable a product to be traced from the point of importation to its destination, as well as back to the producer/supplier. The comment states that substantial information about a product imported legally into the United States is already held in the TTB database. (Response) Unlike products regulated under the exclusive jurisdiction of USDA under the FMIA, the PPIA, or the EPIA, Congress did not exempt alcoholic beverages from the scope of the recordkeeping requirements. FDA has not excluded alcoholic beverages from the scope of this final rule because FDA believes that these records are needed to help the Secretary to identify the immediate previous sources and the immediate subsequent recipients of food to address credible threats of serious adverse health consequences or death to humans or animals. Further, FDA reiterates that, to the extent that you already keep the information required by this final rule to comply with TTB requirements, or for any other reason, you do not need to establish and maintain duplicative records. In addition, securing a ‘legislative amendment’ to the Bioterrorism Act, as the comment suggests, is beyond the scope of this rulemaking.

The 7% discount rate is not a discount for organizations. The discount rate is a part of a formula used in a business impact analysis calculation. When calculating 20 years in the future, a discount rate is used to determine the net present value of money. Discount rates are explained in step seven of OMB Circular A-4: Regulatory Impact Analysis: A Primer. The DoD does not agree with the commenter’s assertion that the cost estimates greatly understate the costs and burden to Level 1 compliance. The 15 FAR security requirements that comprise CMMC Level 1 should already have the requirements implemented if an OSA network processes, stores, or transmits FCI. In addition to NIST SP 800-171A Jun2018, the CMMC Level 1 Assessment Guide provides supplemental information to help facilitate implementation and assessment of the Level 1 security requirements. b. Economic Impact Comment: One comment suggested the government evaluate the economic impact of implementing the rule’s reporting requirements at scale. Another comment expressed the notion that the cost impact analysis does not account for the free market response, referring to the associated cost increases and schedule delays that directly impact the warfighter and taxpayer. The commentor suggested the cost could dwarf both the cost of implementing compliance and achieving certification. One comment stated the CMMC Level 2 and Level 3 cost burdens for companies that were historically never subjected to such requirements may be disproportionate to the risk their operations pose to the inadvertent disclosure of CUI or FCI. It suggested ensuring requirements be proportional to the subcontractor’s activity and risk levels. The comment further mentioned that costs may be passed on to the prime contractor, and DoD should consider providing recovery costs in the price of implementation. One comment stated the 100% compliance to CMMC Level 2 certification may be financially unachievable and suggests if a risk assessment shows the likelihood of harm is

comparatively low, the DoD should direct CMMC Program assessors to use their professional judgments and not require seeking maximum evidence of compliance where there is evidence of sufficiency. Response: The DoD has already evaluated the reporting requirements and the analysis of the costs is provided in the Regulatory Impact Analysis published with this rule. The DoD declined to respond to speculative or editorial comments about downstream impacts of the market's reaction to CMMC, all of which are beyond the scope of this rule. The DoD declined the recommendation to restructure CMMC to be proportional to the subcontractor's activity and risk levels. DoD must enforce CMMC requirements uniformly across the Defense Industrial Base for all contractors and subcontractors who process, store, or transmit CUI. The value of information (and impact of its loss) does not diminish when the information moves to contractors and subcontractors.

- Establish configuration control for security purposes (Priority A). - Supercomputer sites are high priority. - Distribute/support use of automated security management tools (e.g. COPS). - Establish a security perimeter protection capability (Priority B) (e.g. filters, control gateways, Simple Network Management Protocol (SNMP)). - Establish security audit information collection and review capability (Priority B). 5. use of privacy enhanced mail for sensitive communication for administration and security officers, Kerberos, Distributed System Security Architecture (DASS); 6. raising the level of attention with respect to configuration and operation of security relevant portions of the system within a particular site, particularly the domain name service; and 7. a potpourri of administrative and operational considerations - development of security policies at each center, education of people, careful configuration of the cryptographic parts of each site, fire drills so that timely and effective action can take place when an intrusion is discovered to be in progress, and spending time keeping abreast of the technologies. Crocker inquired about the memory requirements needed to run Kerberos. Schiller stated the binary file 'rlogin' is required along with a few configuration files. This resides in about 50-60 Kbytes of memory on a VAX. The DES layer can be optimized to gain additional space. At one point, Kerberos was running on a 256K PC. It will presently run on a laptop computer.

CM.L2-3.4.7 · Nonessential Functionality CMMC Assessment Guide · Level 2 | Version 2.13 106
Interview [SELECT FROM: Personnel with responsibilities for reviewing programs, functions, ports, protocols, and services on the system; personnel with information security responsibilities; system or network administrators; system developers]. Test [SELECT FROM: Organizational processes for reviewing and disabling nonessential programs, functions, ports, protocols, or services; mechanisms implementing review and handling of nonessential programs, functions, ports, protocols, or services; organizational processes preventing program execution on the system; organizational processes for software program usage and restrictions; mechanisms supporting or implementing software program usage and restrictions; mechanisms preventing program execution on the system]. DISCUSSION [NIST SP 800-171 REV. 2]93 Restricting the use of nonessential software (programs) includes restricting the roles allowed to approve program execution; prohibiting auto-execute; program blacklisting and whitelisting; or restricting the number of program instances executed at the same time. The organization makes a security-based determination which functions, ports, protocols, and/or services are restricted. Bluetooth, File Transfer Protocol (FTP), and peer-to-peer networking are examples of protocols organizations consider preventing the use of, restricting, or disabling. FURTHER DISCUSSION Organizations should only use the minimum set of programs, services, ports, and protocols required for to accomplish the organization's mission. This has several implications: · All unnecessary programs and accounts are removed from all endpoints and servers. · The organization makes a policy decision to control the execution of programs through either whitelisting or blacklisting. Whitelisting means a program can only run if the software has been vetted in some way, and the executable name has been entered onto a list of allowed software. Blacklisting means any software can execute as long it is not on a list of known malicious software. Whitelisting provides far more security than blacklisting, but the organization's policy can direct the implementation of either approach. Control of execution applies to both servers and endpoints. · The organization restricts the use of all unnecessary ports, protocols, and system services in order to limit entry points that attackers can use. For example, the use of the FTP service is eliminated from all computers, and the associated ports are blocked unless a required service utilizes those ports. The elimination of nonessential functionality on the network and systems provides a smaller attack surface for an attacker to gain access and take control of your network or systems. This requirement, CM.L2-3.4.7, which requires limiting functionality to essential programs, ports, protocols, and services, extends CM.L2-3.4.6, which requires adherence to the 93 NIST SP 800-171 Rev. 2, pp. 22-23.

The primary food safety benefits from this rule are from the number of illnesses averted due to improved recordkeeping practices. Improved recordkeeping practices result in faster traceback investigations and higher traceback completion rates, which will reduce the expected number of illnesses from intentional and unintentional outbreaks. The following diagram visually depicts the benefits from faster traceback times from the recordkeeping rule. The number of onsets of new illnesses and outbreak investigation duration curves overlap to estimate the number of days that an investigation is likely to reduce the duration of an outbreak. With faster traceback times, the distribution of the durations of outbreak investigations shifts to the left from existing to improved, reducing even further the number of days of an outbreak. This diagram assumes the outbreak is still going on at the time the traceback investigation begins. The reduced number of days of an outbreak can then be translated into a reduced number of illnesses from an outbreak. There are two ways that the recordkeeping rule speeds up traceback investigations: (1) Higher records quality means that traceback investigators spend less time trying to find and analyze information that might have been missing or incomplete had there been no rule and (2) the rule makes failure to provide records within the required time period a violation, thus increasing cooperation with investigators who need rapid access to records. Greater traceback speeds result in more recalls (if the product is still in the marketplace), administrative detentions (under section 303 of the Bioterrorism Act), import actions, closures, and other preventive actions that reduce the number of illnesses during an outbreak. The following is a description of the model used to measure the benefits from the recordkeeping rule.

- i. Given the speed of the initial recognition and epidemiological investigation of an outbreak, the benefits from the recordkeeping rule (printed page 71616) depend on the following factors: (1) the average duration of a traceback investigation, (2) the average number of traceback investigations prematurely terminated for reasons of poor records quality, and (3) the distributions of outbreak durations and sizes.
- ii. The average duration of a traceback investigation depends on the number of point-of-service and distributor investigative visits per traceback investigation, and the average duration of an investigative visit. The quantity of records that needs to be reviewed is an important determinant of the duration of a traceback investigation. However, we assume that the change in the quantity of records requested is much smaller than the change in the quality of the records requested as a result of this final rule. We therefore omit the quantity of records reviewed during a traceback investigation as a modeling consideration when measuring the impact of the final rule.
- iii.

There are four stages in an outbreak investigation. The first stage is the preliminary investigation of laboratory results and epidemiological evidence used to determine the parameters of the outbreak, including the following: number ill, food vehicle contaminated, microbial or other agent responsible, potential commercial sources of contamination, as well as the degree of confidence in the information on each of these parameters. The second stage of the outbreak investigation is the decision making part, when FDA determines what resources will be committed to proceed further in the investigation. The third stage is the traceback investigation, which is conducted to do the following: (1) Identify the source and distribution of the implicated food and remove the contaminated food from the marketplace; (2) distinguish between two or more implicated food products; and (3) determine potential routes and sources of contamination in order to prevent future illnesses, or to treat persons sooner for the identified contaminants. The traceback investigation involves investigative visits by FDA inspectors to points of service, which are the facilities where consumers had purchased the contaminated food, and also distribution facilities. A fourth stage is the source investigation of the specific practices at the farm, transportation, or other facility that may have led to the outbreak. For many outbreaks, the source investigation occurs well after any preventive action can be taken to limit the number of illnesses. This would be true for outbreaks from contaminated foods with short shelf lives that no longer are in circulation at the time of the source investigation, or from contaminations occurring at banquets, parties, or other one-time events where the source investigation cannot limit the size of the outbreak. For these outbreaks, the improved recordkeeping practices specified in the final rule would not improve FDA's current ability to limit the size of the outbreak, or prevent additional illnesses. (printed page 71623) However, for certain products such as eggs, sprouts, and other fresh products, additional illnesses due to conditions at the source may continue if shipments from contaminated facilities continue. The same may also be true for perishable foods imported on a frequent basis from contaminated facilities. For these kinds of outbreaks, the ability to more rapidly implicate a contaminated farm or manufacturing source will improve FDA's ability to limit the size of the outbreak, or prevent its recurrence.

7. The Duration of Traceback Investigations, and Numbers of

Premature Terminations

(Response) In response to these comments and to ensure that FDA is fulfilling Congress's intent to exempt ·farms·, FDA has revised the definition of farm in the final rule to state that a ·farm· means ·a facility in one general physical location devoted to the growing and harvesting of crops, the raising of animals (including seafood), or both·, and that ·[w]ashing, trimming of outer leaves, and cooling produce are considered part of harvesting·. FDA considers several of the activities identified in the comments to be ·packing or holding·, including sorting, grading, wrapping, and boxing harvested food for the sole purpose of transporting this food off the farm. FDA also considers placing stickers on produce grown or consumed on a farm to be part of ·packing·. FDA notes that the definition of ·farm· includes facilities that pack or hold food, provided all food used in such activities is grown, raised, or consumed on that farm or another farm under the same ownership. Thus, a farm that performs these packing and holding activities will not necessarily cease to be a farm and therefore cease to be exempt from these regulations. Similarly, FDA considers several of the activities identified in the comment (waxing, milling, and grinding) to be manufacturing/processing. A farm that performs these activities will not necessarily cease to be a farm because the definition of ·farm· includes facilities that manufacture/process food, provided that all food used in these activities is consumed on that farm or another farm under the same ownership. FDA is aware that a number of other activities may affect an establishment's status as a ·farm· under this final rule. Thus, the agency is providing the following additional clarification. First, FDA considers application of a pesticide to a crop to be an integral part of growing and harvesting crops and therefore considers the activity to be covered by the ·farm· definition. Therefore, an establishment devoted to the growing and harvesting of crops that applies a pesticide to its crops is a ·farm· as defined in this final rule.

provides that if a provision of law contains criminal or civil penalties, or if the FAR Council makes a written determination that it is not in the best interest of the Federal Government to exempt contracts or subcontracts at or below the SAT, the law will apply to them. The Director, DPAP, is the appropriate authority to make comparable determinations for regulations to be published in the DFARS, which is part of the FAR system of regulations. DoD has made that determination, therefore this rule does apply below the SAT. Given that the requirements of section 806 of the NDAA for FY 2011 and section 806 of the NDAA for FY 2013 were enacted to protect the supply chain, which in turn protects NSS from malicious actions, DoD has determined that it is in the best interest of the Federal Government to apply the rule to contracts below the SAT, as defined at FAR 2.101. An exception for contracts for the acquisition below the SAT would exclude contracts intended to be covered by the law, thereby undermining the overarching public policy purpose of the law. B. Applicability to Contracts for the Acquisition of Commercial Items, Including COTS Items 41 U.S.C. 1906 governs the applicability of laws to contracts for the acquisition of commercial items, and is intended to limit the applicability of laws to contracts for the acquisition of commercial items. 41 U.S.C. 1906 provides that if a provision of law contains criminal or civil penalties, or if (printed page 67250) the FAR Council makes a written determination that it is not in the best interest of the Federal Government to exempt commercial item contracts, the provision of law will apply to contracts for the acquisition of commercial items. Likewise, 41 U.S.C. 1907 governs the applicability of laws to COTS items, with the Administrator for Federal Procurement Policy the decision authority to determine that it is in the best interest of the Government to apply a provision of law to acquisitions of COTS items in the FAR. The Director, DPAP, is the appropriate authority to make comparable determinations for regulations to be published in the DFARS, which is part of the FAR system of regulations. Given that the requirements of section 806 of the NDAA for FY 2011 and section 806 of the NDAA for FY 2013 were enacted to protect the supply chain, which in turn protects NSS from malicious actions, DoD has determined that it is in the best interest of the Federal Government to apply the rule to contracts for the acquisition of commercial items, including COTS items, as defined at FAR 2.101. An exception for contracts for the acquisition of commercial items, including COTS items, would exclude contracts intended to be covered by the law, thereby undermining the overarching public policy purpose of the law. IV. Executive Orders 12866 and 13563

These network switches and routers are highly reconfigurable, and therefore, allow the system to implement various network topologies for performance testing. - [1] R. Candell, T. Zimmerman and K. Stouffer, "An Industrial Control System Cybersecurity Performance Testbed, NISTIR 8089," National Institute of Standards and Technology (NIST), Gaithersburg, MD, 2015. - [2] J. J. Downs and E. F. Vogel, "A Plant-Wide Industrial Process Control Problem," Computers and Chemical Engineering, vol.

17, no. 3, pp. 245-255, 1993. - [3] L. Ricker, "Decentralized control of the Tennessee Eastman Challenge Process," *Journal of Process Control*, vol. 6, no. 4, pp. 205-221, 1996. - [4] T. Zimmerman, "Metrics and KPI for Robotic Cybersecurity Performance Analysis, NISTIR 8177," National Institute of Standards and Technology (NIST), Gaithersburg, MD, 2016. - [5] I. C. Garretson, M. Mani, S. Leong, K. W. Lyons and K. R. Haapala, "Terminology to support manufacturing process characterization and assessment for sustainable production," *Journal of Cleaner Production*, vol. 139, p. 986-1000, 2016. - [6] F.-L. Lian, J. R. Moyne and D. M. Tilbury, "Performance Evaluation of Control Networks: Ethernet, ControlNet, and DeviceNet," *IEEE Control Systems Magazine*, February 2001. - [7] G. Buckbee, "Realtime Metrics for Process Performance," *Chemical Engineering*, June 2007. - [8] M. Newton, "KPIs for Industrial Automation and Process Control," Opto22, Temecula, CA, 2017. - [9] M. Davidson, "28 Manufacturing Metrics that Actually Matter," LNS Research, Cambridge, MA, 2013.

PE.L2-3.10.4 · Physical Access Logs [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13 187 means such as badge readers. Whatever means you use, you need to retain the access records for the time period that your company has defined. Example You and your coworkers like to have friends and family join you for lunch at the office on Fridays. Your small company has just signed a contract with the DoD, however, and you now need to document who enters and leaves your facility. You work with the reception staff to ensure that all non-employees sign in at the reception area and sign out when they leave [a]. You retain those paper sign-in sheets in a locked filing cabinet for one year. Employees receive badges or key cards that enable tracking and logging access to company facilities. Potential Assessment Considerations · Are logs of physical access to sensitive areas (both authorized access and visitor access) maintained per retention requirements [a]? · Are visitor access records retained for as long as required [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.10.4 · FAR Clause 52.204-21 Partial b.1.ix

Guide to Auditing for Controls and Security: A System Development Life Cycle Approach in The National Bureau of Standards' was established by an act of Congress on March 3, 1901. The Bureau's overall goal is to strengthen and advance the nation's science and technology and facilitate their effective application for public benefit. To this end, the Bureau conducts research to assure international competitiveness and leadership of U.S. industry, science and technology. NBS work involves development and transfer of measurements, standards and related science and technology, in support of continually improving U.S. productivity, product quality and reliability, innovation and underlying science and engineering. The Bureau's technical work is performed by the National Measurement Laboratory, the National Engineering Laboratory, the Institute for Computer Sciences and Technology, and the Institute for Materials Science and Engineering. Conducts research and provides scientific and technical services to aid Federal agencies in the selection, acquisition, application, and use of computer technology to improve effectiveness and economy in Government operations in accordance with Public Law 89-306 (40 U.S.C. 759), relevant Executive Orders, and other directives; carries out this mission by managing the Federal Information Processing Standards Program, developing Federal ADP standards guidelines, and managing Federal participation in ADP voluntary standardization activities; provides scientific and technological advisory services and assistance to Federal agencies; and provides the technical foundation for computer-related policies of the Federal Government. The Institute consists of the following divisions:

The DoD has developed CMMC to increase consistency of implementation of NIST SP 800-171 R2 and NIST SP 800-172 Feb2021. Specifically, this rule provides extensive information on scoring methodology, in an effort to improve self-assessments. The use of independent C3PAOs further enforces consistency for those companies that need to meet a CMMC Level 2 certification requirement. The DoD has considered the suggestions and declines to modify the phase-in periods based on total score required, or other criteria, which would not provide the desired improvements in DIB cybersecurity. The DoD notes the commenter's concern that self-assessments go away after Phase 4. Requirements from earlier phases continue as each additional phase is implemented. When applicable, self-assessments will still be allowed, as appropriate, in Phase 4. This rule describes flow down requirements to subcontractors. This rule makes no change to 48 CFR 252.204-7008 . 8. Commercially Available Off-the-Shelf (COTS) Procurements Comment: One comment suggested the definition of COTS should be more explicitly defined or the model outlined in §170.2 should encompass COTS products. Two comments questioned the exemption of CMMC requirements for contracts or subcontracts exclusively for commercial off-the-shelf (COTS) items. Others questioned applicability of CMMC requirements to COTS procurements and/or purchases at or below the micro-purchase threshold. Finally, one commenter questioned the validity of a COTS exclusion, stating that no COTS components are exempt from DoD's

certification requirements from DISA or NSA. Response: The term Commercially available off-the-shelf (COTS) is defined in FAR part 2.101. Some comments pertained to content of the 48 CFR part 204 CMMC Acquisition rule, including applicability of CMMC clauses to COTS procurements and/or those below the micro-purchase threshold. Such comments are not within the scope of this CMMC 32 CFR part 170 CMMC Program rule, which outlines program requirements and not acquisition procedures. CMMC requirements do not apply to contracts and subcontracts that are exclusively for the delivery of COTS products to a DoD buyer. The exemption does not apply to a contractor's use of COTS products within its information systems that process, store, or transmit CUI. CMMC assessments are conducted on contractor owned information systems to ascertain compliance with the designated FAR, DFARS, and NIST requirements. 9. Specific Product Recommendations Comment: One managed service provider expressed concern that the specific tools they use to provide services might be considered Security Protection Assets or generate Security Protection Data in the context of CMMC assessment requirements, which might (printed page 83112)

This report features some of our most significant accomplishments during Fiscal Year (FY) 2017 in risk management, cryptography, identity and access management, vulnerability management, education and workforce development, and internet and communications infrastructure, as well as our efforts to transition our work into common practice. Below are just a few highlights of the work carried out in 2017. - In recent years, there has been a substantial amount of research on quantum computers - machines that exploit quantum mechanical phenomena to solve problems that are difficult or intractable for conventional computers. If large-scale quantum computers are ever built, they will be able to break the existing infrastructure of public-key cryptography. Employing NIST's proven approach of worldwide open competitions, in 2016 we solicited submissions for quantum-resistant public-key cryptographic algorithms for standards. These algorithms must be secure against both quantum and classical computers and should interoperate with existing communications protocols and networks. We now are engaging the cryptographic community in the difficult work of determining how the 69 submissions we received in 2017 meet the competition's exacting requirements. - In instances where many devices are interconnected and working in concert to accomplish some task, security and privacy can be very important but hard to achieve due to limited capabilities available to handle modern cryptographic algorithms. This includes automotive systems, sensor networks, healthcare, distributed control systems, the smart grid, and cyber-physical systems and the Internet of Things (IoT). Recognizing this special challenge and in order to gain greater awareness and involvement with the cryptographic community, NIST shared its findings in this area (known as lightweight cryptography) and presented our plans to address standardization issues for community feedback.

3.1.6 Step 6: Approve or Reject the Information Exchange... 3.1.6 Step 6: Approve or Reject the Information Exchange The joint planning team submits the proposed agreements to the relevant AO or other risk management official from each organization and requests approval for the information exchange.

According to Case Studies in Cyber Supply Chain Risk Management_ Summary of Findings and Recommendations, References: gency or Internal Report (IR) 8179. <https://doi.org/10.6028/NIST.IR.8179> <!-- image --> - National Institute of Standards and Technology (2001) Security Requirements for Cryptographic Modules. (U.S. Department of Commerce, Washington, DC), Federal Information Processing Standards Publication (FIPS) 140-2, Change Notice 2 December 03, 2002. <https://doi.org/10.6028/NIST.FIPS.140-2> - National Institute of Standards and Technology (2018) Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1. (National Institute of Standards and Technology, Gaithersburg, MD). <https://doi.org/10.6028/NIST.CSWP.04162018> - North American Electric Reliability Corporation (NERC) (2019) Enforcement Actions 2019 . Available at - Sarbanes-Oxley Act of 2002, Pub. L. 107-204, 116 Stat. 745. <https://www.govinfo.gov/app/details/PLAW-107publ204> - U.S. Customs and Border Protection (2020) CTPAT: Customs Trade Partnership Against Terrorism . Available at <https://www.cbp.gov/border-security/ports-entry/cargo-security/ctpat> <!-- image -->

Safeguard sensitive information to enable and protect the warfighter Enforce DIB cybersecurity standards to meet evolving threats Ensure accountability while minimizing barriers to compliance with DoD requirements Perpetuate a collaborative culture of cybersecurity and cyber resilience Maintain public trust through high professional and ethical standards The CMMC 2.0 Program has three key features: Tiered Model: CMMC requires companies entrusted with national security information to implement cybersecurity standards at progressively advanced levels, depending on the

type and sensitivity of the information. The program also describes the process for requiring protection of information flowed down to subcontractors. Assessment Requirement: CMMC assessments allow the Department to verify the implementation of clear cybersecurity standards. (printed page 89059) Implementation through Contracts: Once CMMC is fully implemented, certain DoD contractors handling sensitive unclassified DoD information will be required to achieve a particular CMMC level as a condition of contract award. CMMC 2.0-Overview as Proposed by This Rule Current Requirements for Defense Contractors and Subcontractors Currently, federal contracts (including defense contracts) involving the transfer of FCI to a non-Government organization follow the requirements specified in FAR clause 52.204-21, Basic Safeguarding of Covered Contractor Information Systems . [5] FAR clause 52.204-21 requires compliance with 15 security requirements, FAR 52.204-21(b)(1), items (i) through (xv). These requirements are elementary for any entity wishing to achieve basic cybersecurity. Defense contracts involving the transfer of CUI to a non-Government organization may include applicable requirements of DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting . [6] The DFARS clause 252.204-7012 requires defense contractors to provide adequate security on all covered contractor information systems by implementing the 110 security requirements specified in the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations. The DFARS clause 252.204-7012 includes additional requirements; for example, defense contractors must meet Federal Risk and Authorization Management Program (FedRAMP) standards by confirming that their Cloud Service Providers (CSP) have achieved the FedRAMP Baseline Moderate or Equivalent standard. The DFARS clause 252.204-7012 also requires defense contractors to flow down all the requirements to their subcontractors. Currently, to comply with DFARS clause 252.204-7012, contractors are required to develop a System Security Plan (SSP) [7]

OSCs will submit in SPRS an initial affirmation of compliance, and, if necessary, a POA&M closeout affirmation, and then annually thereafter, an affirmation of continued compliance as set forth in 32 CFR 170.22 . The Level 3 Certification Assessment cost burdens are included in this part with the exception of the requirement for the OSC to upload the affirmation in SPRS that is included in the Title 48 acquisition rule and an update to DFARS collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Additionally, the information collection reporting requirements for the CMMC instantiation of eMASS are included in a separate ICR for this part and cover only those requirements pertaining to the CMMC process. As described, the CMMC Program couples an affirmation of compliance with certification assessment requirements to verify OSA implementation of cybersecurity requirements, as applicable. The CMMC Program addresses DoD's need to protect its sensitive unclassified information during the acquisition and sustainment of products and services from the DIB. This effort is instrumental in ensuring cybersecurity is the foundation of future DoD acquisitions. Policy Problems Addressed by CMMC 2.0 Implementation of the CMMC Program is intended to solve the following policy problems: Verifies the Contractor Cybersecurity Requirements Neither FAR clause 52.204-21 nor DFARS clause 252.204-7012 provide for DoD assessment of a defense contractor or subcontractor's implementation of the information protection requirements within those clauses. Defense contractors represent that they will implement the requirements in NIST SP 800-171 Rev 2 upon submission of their offer. Findings from DoD Inspector General report (DODIG-2019-105 ·Audit of Protection of DoD Controlled Unclassified Information on Contractor-Owned Networks and Systems·) indicate that DoD contractors did not consistently implement mandated system security requirements for safeguarding CUI and recommended that DoD take steps to assess a contractor's ability to protect this information. CMMC adds new assessment requirements for contractor implementation of underlying information security requirements, to allow DoD to assess a defense contractor's cybersecurity posture using authorized or accredited C3PAOs. The contractor and subcontractor must achieve the required CMMC Level as a condition of contract award. Implementation of Cybersecurity Requirements

and - Establishing and maintaining a privacy continuous monitoring program to maintain ongoing awareness of privacy risks and assess privacy controls at a frequency sufficient to ensure compliance with privacy requirements and manage privacy risks.

Access Control 20 correct Security targets allow flexibility by providing a vehicle for a producer to specify security objectives, services, and/or mechanisms that exceed those found an existing profile. For example, many C2 systems meet the B3 DiscreticMiary Access Control (DAQ mechanism requirements. Both groups felt that having a security target without having a protection profile may

be sufficient in cases where there is no need to have a general set of requirements that several vendors can build to, or when specifying the security aspects of a 'one shot' system or product prototype. If a single unique product is being built, a security target is all that is needed and can be evaluated against The Federal Criteria needs to be designed in such a way as to not shut out good security solutions. Allowing products to be evaluated solely against security targets provides a means of addressing this concern. Such an evaluation can encourage a vendor to find a solution to a user's problem, even if it doesn't meet an existing profile. - Precision in Terminology - Identification and Authentication - Access Control - Availability & Fault Tolerance - Policy Neutral Criteria - TCB & Reference Monitor Focus - Integrity - Open-Ended Criteria - Issues from the attendees

The DoD considered duration of assessment validity periods and has chosen to require self-assessment of the basic Level 1 requirements every year, rather than every three years. Levels 2 and 3 require implementation of a significantly larger number of more complex security requirements, which require more time and attention to assess. The DoD also declines to delete the annual affirmation requirement and does not agree that it equates to an annual assessment. The rule was modified to clarify that reassessments may be required based on post-assessment indicators of cybersecurity issues or non-compliance and are different from new assessments that occur when an assessment validity period expires. Reassessment is expected to be infrequent, conducted by the DoD, and necessary when cybersecurity risks, threats, or awareness have changed, or indicators of cybersecurity deficiencies and/or non-compliance are present. When required, DCMA DIBCAC will initiate the re-assessment process using established procedures. The rule has been further updated to add this DCMA DIBCAC responsibility in §170.7. OSCs seeking confirmation upon CMMC Level 2 POA&M close-out may undergo POA&M close-out assessment by a C3PAO, which is different from reassessment. Self-assessments and certification assessments are valid for a defined CMMC Assessment Scope as outlined in §170.19 CMMC Scoping. A new assessment is required if there are significant architectural or boundary changes to the previous CMMC Assessment Scope. Examples include, but are not limited to, expansions of networks or mergers and acquisitions. Operational changes within a CMMC Assessment Scope, such as adding or subtracting resources within the existing assessment boundary that follow the existing SSP do not require a new assessment, but rather are covered by the annual affirmations to the continuing compliance with requirements. The CMMC rule does not prohibit an OSA from using an operational plan of action at any CMMC Level to address necessary information system updates, patches, or reconfiguration as threats evolve. If the CMMC Assessment Scope changes, then the current assessment is no longer valid and a new assessment is required. Requirements to notify the contracting agency of compliance changes are described in the 48 CFR part 204 CMMC Acquisition rule. An annual affirmation is required at each CMMC level. 16. CMMC Assessment Scoping Policy Comment: One comment asked whether the requirements of DFARS clause 252.204-7012 apply to the entire contractor-owned information system, or only those components of the system that process, store, or transmit the CUI. Another questioned whether assets that process both FCI and CUI require CMMC Level 1 assessment.

| MECHANISM 1 - - | REF | 1 | 1 -+ +- | R | jCMTSI + | |-----|-----
-----|-----|-----|-----
- | | 1 + Basic Mechanisms: | 1 + Basic Mechanisms: | 1 + Basic Mechanisms: | 1 + Basic Mechanisms: |
1 + Basic Mechanisms: | | Padding | 6.6 | M | M | | Concatenation/Separation | 6.1 | M | M | |
Encapsulation/Decapsulation | 5.5 | M | M | | Address Verification | 6.4 | M | M | | Connection
Integrity | 5.5.2 | | | | direction ind | 6.3.2 | M | M | | transport s/n | 5.5.2 | M | M | 1 |
| 1 + Optional Mechanisms: | 1 + Optional Mechanisms: | 1 + Optional Mechanisms: | 1 + Optional
Mechanisms: | 1 + Optional Mechanisms: | | Encipherment | 6.2 | O | M | 2 | | Data Integrity Check |
6.3.1 | O | M | 2 | | Key Granularity | 5.1 | O | M | 3 | | Connection Integrity 5.5.2 | Connection
Integrity 5.5.2 | Connection Integrity 5.5.2 | Connection Integrity 5.5.2 | Connection Integrity

According to Approaches for Federal Agencies to Use the Cybersecurity Framework, Executive Summary: dards and guidelines. This report illustrates eight example approaches through which federal agencies can leverage the Cybersecurity Framework to address common cybersecurity-related responsibilities. By doing so, agencies can integrate the Cybersecurity Framework with key NIST cybersecurity risk management standards and guidelines that are already in wide use. These eight approaches support a mature agency-wide cybersecurity risk management program: 1. Integrate enterprise and cybersecurity risk management 2. Manage cybersecurity requirements 3. Integrate and align cybersecurity and acquisition processes 4. Evaluate organizational cybersecurity 5. Manage the

cybersecurity program 6. Maintain a comprehensive understanding of cybersecurity risk 7. Report cybersecurity risks 8. Inform the tailoring process The key concepts and cybersecurity approaches described in this document are intended to promote more effective risk management and to encourage dialogue within and among federal agencies.

(E) From subsection (e)(3) because compliance would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation or reveal the identity of witnesses or confidential informants. (F) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (G) From subsection (e)(5) because in the collection of information for law enforcement purposes it is impossible to determine in advance what information is accurate, relevant, timely, and complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light and the accuracy of such information can only be determined in a court of law. The restrictions of subsection (e)(5) would restrict the ability of trained investigators and intelligence analysts to exercise their judgment in reporting on investigations and impede the development of intelligence necessary for effective law enforcement. (H) From subsection (e)(8) because compliance would provide an impediment to law enforcement by interfering with the ability to issue warrants or subpoenas and by revealing investigative techniques, procedures, or evidence. (I) From subsection (f) and (g) because this record system is exempt from the individual access provisions of subsection (d). (J) Consistent with the legislative purpose of the Privacy Act of 1974, the (printed page 14770) DON will grant access to nonexempt material in the records being maintained. Disclosure will be governed by the DON's Privacy Regulation, but will be limited to the extent that the identity of confidential sources will not be compromised; subjects of an investigation of an actual or potential criminal violation will not be alerted to the investigation; the physical safety of witnesses, informants and law enforcement personnel will not be endangered, the privacy of third parties will not be violated; and that the disclosure would not otherwise impede effective law enforcement. Whenever possible, information of the above nature will be deleted from the requested documents and the balance made available. The controlling principle behind this limited access is to allow disclosures except those indicated above. The decisions to release information from these systems will be made on a case-by-case basis. (22) System identifier and name. NM05211-1, Privacy Act Request Files and Tracking System. (i) Exemption.

(1) Whenever an individual submits a Privacy Act request, a case file will be established. This Privacy Act case file is a specific type of file that is governed by a specific Privacy Act system of records notice. In no instance will the individual's Privacy Act request and (printed page 46061) corresponding Army actions be included in the individual's military personnel file or other military filing systems, such as adverse action files or general legal files, and in no instance will the Privacy Act case file be used to make an adverse determination about the individual. (2) The case file will be comprised of the request for access/amendment, grants, refusals, coordination action(s), and all related papers. § 505.6 Amendment of records. (a) Amended records. (1) Individuals are encouraged to periodically review the information maintained about them in Privacy Act systems of records and to familiarize themselves with the amendment procedures established by this part. (2) An individual may request to amend records that are retrieved by his or her name or personal identifier from a system of records unless the system has been exempted from the amendment provisions of the Act. The standard for amendment is that the records are inaccurate as a matter of fact rather than judgment, irrelevant, untimely, or incomplete. The burden of proof is on the requester. (3) The system manager or custodian must review Privacy Act records for accuracy, relevance, timeliness, and completeness. (4) Amendment procedures are not intended to permit individuals to challenge events in records that have actually occurred. Amendment procedures only allow individuals to amend those items that are factually inaccurate and not matters of official judgment (e.g. , performance ratings, promotion potential, and job performance appraisals). In addition, an individual is not permitted to amend records for events that have been the subject of judicial or quasi-judicial actions/proceedings. (b) Proper amendment requests. (1) Amendment requests, except for routine administrative changes, will be in writing. (2) When acting on behalf of a first party requester, an individual must provide written documentation of the first party requester's consent to allow the individual to view his or her records. (3) Amendment is appropriate if it can be shown that: (i) Circumstances leading up to the recorded event were found to be inaccurately reflected in the document; (ii) The record is not identical to the individual's

copy; or (iii) The document was not constructed in accordance with the applicable recordkeeping requirements prescribed in AR 25-400-2, The Army Records Information Management System (ARIMS). (4) Under the amendment provisions, an individual may not challenge the merits of an adverse determination.

, a covered entity that is a governmental entity is in compliance with the requirements of this section if it has in place an arrangement with a business associate that is also a governmental entity where the arrangement meets the (printed page 981) analogous requirements of the Privacy Rule at 45 CFR 164.504(e)(3) . [821] Additionally, 45 CFR 164.314(a)(2)(iii) requires that a business associate and its subcontractor enter into a business associate agreement that meets the same requirements as those that apply to a business associate agreement between a covered entity and business associate. As described above, a business associate agreement must include a provision that requires a business associate to report to the covered entity any known security incident. The term "security incident" includes both attempted and successful unauthorized events in an information system. [822] The Security Rule does not prescribe the timing and frequency with which a business associate reports a security incident to the covered entity (or subcontractor to a business associate). [823] Instead, regulated entities may determine the appropriate timing and frequency as part of their business associate agreement, consistent with the requirements of the Breach Notification Rule. [824] Depending on the size of the regulated entity, the number of security incidents it experiences may vary, ranging from the occasional incident experienced by a small regulated entity to more than 1,000 per hour for a large regulated entity. [825] Given that such incidents may have little to no effect if the regulated entity's electronic information systems are able to deter it, it may not be necessary for a business associate to report the security incidents immediately to a covered entity (or a subcontractor to a business associate). Additionally, as discussed above, regulated entities are required to establish, and implement as needed, a contingency plan [826] that includes the policies and procedures for responding to an emergency or other occurrence that damages systems that contain ePHI. Such emergencies or other occurrences could include a fire, vandalism, system failure, or a natural disaster. [827] The Department believes that, in some instances, a security incident would also be an emergency or other occurrence that could require a regulated entity to activate its contingency plan. [828] As the Department previously explained, a contingency plan is the only way to protect the confidentiality, integrity, and availability of ePHI during unexpected events that may expose ePHI because the usual security measures may be disabled, ignored, or not observed. [829] b. Issues To Address

(i)(A) A covered entity may permit a business associate to create, receive, maintain, or transmit electronic protected health information on the covered entity's behalf only if the covered entity obtains satisfactory assurances, in accordance with § 164.314(a), that the business associate will comply with this subpart and verifies that the business associate has deployed technical safeguards in accordance with the requirements of § 164.312. (B) A covered entity is not required to obtain such satisfactory assurances or verification from a business associate that is a subcontractor. (ii) A business associate may permit a business associate that is a subcontractor to create, receive, maintain, or transmit electronic protected health information on its behalf only if the business associate obtains satisfactory assurances, in accordance with § 164.314(a), that the subcontractor will comply with the requirements of this subpart and verifies that the business associate that is a subcontractor has deployed technical safeguards in accordance with the requirements of § 164.312. (2) Implementation specifications (i) Written contract or other arrangement. Document the satisfactory assurances required by paragraph (b)(1)(i) or (ii) of this section through a written contract or other arrangement with the business associate that meets the applicable requirements of § 164.314(a). (ii) Written verification. Obtain written verification from the business associate at least once every 12 months that the business associate has deployed the technical safeguards as required by § 164.312 through both of the following: (A) A written analysis of the business associate's relevant electronic information systems by a person with appropriate knowledge of and experience with generally accepted cybersecurity principles and methods for ensuring the confidentiality, integrity, and availability of electronic protected health information to verify compliance with each standard and implementation specification in § 164.312. (B) A written certification that the analysis has been performed and is accurate by a person who has the authority to act on behalf of the business associate. (3) Standard: Delegation to business associate. (i) A covered entity or business associate may permit a business associate to serve as their designated security official. (ii) A covered entity or business associate that delegates

actions, activities, or assessments required by this subpart to a business associate remains liable for compliance with all applicable provisions of this subpart. § 164.310 Physical safeguards. Each covered entity and business associate must, in accordance with §§ 164.306 and 164.316, implement all of the following physical safeguards to protect the confidentiality, integrity, and availability of all electronic protected health information that it creates, receives, maintains, or transmits: (a) Standard: Facility access controls (1) General.

. Once a requester's commercial interest has been determined, the Components should then determine if the disclosure would be primarily in that interest. This requires a balancing test between the commercial interest of the request against any public benefit to be derived as a result of that disclosure. Where the public interest is served above and beyond that of the requester's commercial interest, a waiver or reduction of fees would be appropriate. Conversely, even if a significant public interest exists, and the relative commercial interest of the requester is determined to be greater than the public interest, then a waiver or reduction of fees would be inappropriate. As examples, news media organizations have a commercial interest as business organizations; however, their inherent role of disseminating news to the general public can ordinarily be presumed to be of a primary interest. Therefore, any commercial interest becomes secondary to the primary interest in serving the public. Similarly, scholars writing books or engaged in other forms of academic research may recognize a commercial benefit, either directly, or indirectly (through the institution they represent); however, normally such pursuits are primarily undertaken for educational purposes, and the application of a fee charge would be inappropriate. Conversely, data brokers or others who merely compile Government information for marketing can normally be presumed to have an interest primarily of a commercial nature. (3) Components are reminded that the factors and examples used in this paragraph are not all inclusive. Each fee decision must be considered on a case-by-case basis and upon the merits of the information provided in each request. When the element of doubt as to charging or waiving the fee cannot be clearly resolved, Components should rule in favor of the requester. (4) In addition, the following additional circumstances describe situations where waivers or reductions of fees are most likely to be warranted: (i) A record is voluntarily created to prevent an otherwise burdensome effort to provide voluminous amounts of available records, including additional information not requested. (ii) A previous denial of records is reversed in total, or in part, and the assessable costs are not substantial (e.g. \$25.00-\$50.00). (d) Fee assessment . (1) Fees may not be used to discourage requesters. Assessable FOIA fees are limited to standard charges for direct search, review (in the case of commercial requesters), and duplication. (2) Fees are assessed based on the category determined to be appropriate for the requester's status and the FOIA request should contain a willingness to pay fees appropriate to that category. The categories are identified below: (i) Commercial . Requesters should indicate a willingness to pay all search, review, and duplication costs when the records are requested for commercial use.

The DoD established the voluntary DIB CS/IA program to enhance and supplement DIB participants' capabilities to safeguard DoD unclassified information that resides on, or transits, DIB unclassified information systems. At the core of the program is a bilateral cyber security information sharing activity, in which DoD provides cyber threat information and information assurance (IA) best practices to DIB companies to enhance and supplement DIB companies' capabilities to safeguard DoD unclassified information; and in return, DIB companies report certain types of cyber intrusion incidents to the Defense Cyber Crime Center's DoD-DIB Collaborative Information Sharing Environment (DCISE), DoD's operational focal point for cyber threat information sharing and incident response under this program. The DoD analyzes the information reported by the DIB company regarding any such cyber incident, to glean information regarding cyber threats, vulnerabilities, and the development of effective response measures. In addition to this initial reporting and analysis, the DoD and DIB company may pursue, on a voluntary basis, follow-on, more detailed, digital forensics analysis or damage assessments of individual incidents, including sharing of additional electronic media/files or information regarding the incident or the affected systems, networks, or information. The information sharing arrangements between the DoD and each participating DIB company are memorialized in a standardized bilateral Framework Agreement (FA), signed by the participating DIB company and the Government, that implements the requirements of this part and is signed by the participating DIB company and the Government. The FA is available to eligible DIB companies during the application process. As provided by the FA, participation in the program is entirely voluntary and does not obligate any DIB participant to change its information systems or otherwise alter its normal conduct of cyber security activities. In keeping with the voluntary, collaborative nature of the activity described in the FA, each Party bears responsibility

for its own actions under this FA. The FA emphasizes sharing to the greatest extent possible information to provide the clearest understanding of the cyber threat. This will allow the Company to improve defense and remediation efforts and allow the Government to assess the damage or impact to defense information and programs entrusted to the Company.

Tim Grance and Murugiah Souppaya of NIST and Lucinda Gagliano, Thomas Goff, and Pius Uzamere of Booz Allen Hamilton for their keen and insightful assistance throughout the development of the document. The authors would also like to express their thanks to security experts Mike Danseglio (Microsoft), Kurt Dillard (Microsoft), Michael Gerdes (Getronics RedSiren Security Solutions), Peter Szor (Symantec), Miles Tracy (U.S. Federal Reserve System), and Lenny Zeltser (Gemini Systems LLC), as well as representatives from the General Accounting Office, and for their particularly valuable comments and suggestions.

Begins one calendar year following the start date of Phase 2. In addition to Phase 1 and 2 requirements, DoD intends to include the requirement for CMMC Status of Level 2 (C3PAO) for all applicable DoD solicitations and contracts as a condition of contract award and as a condition to exercise an option period on a contract awarded after the effective date. DoD intends to include the requirement for CMMC Status of Level 3 (DIBCAC) for all applicable DoD solicitations and contracts as a condition of contract award. DoD may, at its discretion, delay the inclusion of requirement for CMMC Status of Level 3 (DIBCAC) to an option period instead of as a condition of contract award.

(4) Phase 4, full implementation. Begins one calendar year following the start date of Phase 3. DoD will include CMMC Program requirements in all applicable DoD solicitations and contracts including option periods on contracts awarded prior to the beginning of Phase 4.

§ 170.4 Acronyms and definitions. (a) Acronyms. Unless otherwise noted, the following acronyms and their terms are for the purposes of this part. AC·Access Control APT·Advanced Persistent Threat AT·Awareness and Training C3PAO·CMMC Third-Party Assessment Organization CA·Security Assessment CAICO·CMMC Assessors and Instructors Certification Organization CAGE·Commercial and Government Entity CCA·CMMC-Certified Assessor CCI·CMMC-Certified Instructor CCP·CMMC-Certified Professional CFR·Code of Federal Regulations CIO·Chief Information Officer CM·Configuration Management CMMC·Cybersecurity Maturity Model Certification CMMC PMO·CMMC Program Management Office CNC·Computerized Numerical Control CoPC·Code of Professional Conduct CSP·Cloud Service Provider CUI·Controlled Unclassified Information DCMA·Defense Contract Management Agency DD·Represents any two-character CMMC Domain acronym DFARS·Defense Federal Acquisition Regulation Supplement DIB·Defense Industrial Base DIBCAC·DCMA's Defense Industrial Base Cybersecurity Assessment Center DoD·Department of Defense DoDI·Department of Defense Instruction eMASS·Enterprise Mission Assurance Support Service ESP·External Service Provider FAR·Federal Acquisition Regulation FCI·Federal Contract Information FedRAMP·Federal Risk and Authorization Management Program GFE·Government Furnished Equipment IA·Identification and Authentication ICS·Industrial Control System IIoT·Industrial Internet of Things IoT·Internet of Things IR·Incident Response IS·Information System IEC·International Electrotechnical Commission ISO/IEC·International Organization for Standardization/International Electrotechnical Commission IT·Information Technology L#·CMMC Level Number MA·Maintenance MP·Media Protection MSSP·Managed Security Service Provider NARA·National Archives and Records Administration NAICS·North American Industry Classification System NIST·National Institute of Standards and Technology N/A·Not Applicable ODP·Organization-Defined Parameter OSA·Organization Seeking Assessment OSC·Organization Seeking Certification OT·Operational Technology

approves any materials that are incorporated by reference (as detailed in the Office of the Federal Register's Incorporation By Reference (IBR) Handbook, June 2023). Materials that are incorporated by reference in this rule are reasonably available. Information on how to access the documents is detailed in § 170.2. Materials that are incorporated by reference in this rule are from the NIST (see § 170.2(a)), the Committee on National Security Systems (see § 170.2(b)), and the International Organization for Standardization/International Electrotechnical Commission (ISO/IEC) (see § 170.2(c)) which may require payment of a fee. Note: While the ISO/IEC standards are issued jointly, they are available from the ISO Secretariat (see § 170.2(c)). The American National Standards Institute (ANSI) IBR Portal provides access to standards that have been incorporated by reference in the U.S. Code of Federal Regulations at <https://ibr.ansi.org>. These standards incorporated by the U.S. government in rulemakings are offered at no cost in ·read only· format and are presented for online reading. There are no print or download options. All users will be required to install the FileOpen plug-in and accept an online end user license agreement prior to accessing

any standards. The materials that are incorporated by reference are summarized below. (a) Federal Information Processing Standard (FIPS) Publication (PUB) 200 (FIPS PUB 200), titled "Minimum Security Requirements for Federal Information and Information Systems" is the second of two security standards mandated by the Federal Information Security Management Act (FISMA). It specifies minimum security requirements for information and information systems supporting the executive agencies of the federal government and a risk-based process for selecting the security controls necessary to satisfy the minimum security requirements. This standard promotes the development, implementation, and operation of more secure information systems within the federal government by establishing minimum levels of due diligence for information security and facilitating a more consistent, comparable, and repeatable approach for selecting and specifying security controls for information systems that meet minimum security requirements. This document is incorporated by reference as a source for definitions.

to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (8) System identifier and name. LDIA 0010, Information Requests-Freedom of Information Act (FOIA) and Privacy Act. (i) Exemption. During the course of information requests-FOIA and Privacy Act actions, exempt records/material from other systems of records may become part of this system of records. For such records/material, DIA hereby claims the same exemptions as is claimed for the systems from which such records/material are derived. (ii) Authority. 5 U.S.C. 552a(k)(2) through (k)(7) . (iii) Reasons. Records in a system of records are only exempted from pertinent provisions of 5 U.S.C. 552a to the extent such provisions are identified and an exemption claimed. In general, exemptions claimed protect properly classified information relating to national defense and foreign policy; avoid interference during the conduct of criminal, civil, or administrative actions or investigations; ensure protective services provided the President and others are not compromised; protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations; preserve the confidentiality and integrity of Federal testing materials; and safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule(s) for the systems of records from which the records/materials was derived will identify the specific reasons why the records/materials are exempt from provisions of 5 U.S.C. 552a . (9) System identifier and name. LDIA 12-0002, Privacy and Civil Liberties Case Management System. (i) Exemption. Any portion of this record system which falls within the provisions of 5 U.S.C. 552a(k)(2) and (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons.

(Comment 188) Several comments address the costs of records retention. Several comments suggest that records are often stored off site or at corporate headquarters, with a nonzero cost for retrieval. Another comment recommends that we review our estimate of records retention costs of zero. The comment states that firms that handle products not covered by the juice HACCP regulation (part 120) may not have a records retention strategy and may have to implement a new strategy for records retention and recovery. Several comments express uncertainty with regard to the appropriate records retention time of either 1 year or 2 years for the products that they handle. These comments suggest definitions of "perishable" that would be more consistent with the terminology used in the trade, which is different from the definition in the proposed rule. Recommended records retention times ranged from a low of 6 months for perishable foods, up to 2 years for other foods. (Response) In the PRIA, we used information from preliminary outreach to tentatively conclude that requirements for records retention of 1 year for perishable products, and 2 years for all other foods were consistent with current industry norms. The respondents to the outreach were not necessarily subject to the recordkeeping requirement of the juice HACCP rule, and we assume that the understanding of the term "perishables" by the respondents to that outreach was based on the conventional use of the

term, rather than the definition of the term used in the PRIA. In response to comments, the record retention requirements for nontransporters in the final rule now provide: (1) 6 months for food for which a significant risk of spoilage or significant loss of value occurs within (printed page 71635) 60 days under normal shipping and storage conditions for that food; (2) 1 year for food for which a significant risk of spoilage or significant loss of value occurs within 61 days to 6 months under normal shipping and storage conditions for that food; and (3) 2 years for food for which a significant risk of spoilage or significant loss of value occurs greater than 6 months under normal shipping and storage conditions for that food. (Comment 189) One comment suggests that the estimates of zero storage costs from records retention are too low. The comment estimates that offsite storage and recovery costs range between \$2.50 and \$3.50 per cubic foot per year.

3.6.1 | Continuous Risk Monitoring... 3.6.1 Continuous Risk Monitoring Because cybersecurity risks and their impacts on other risks frequently change, enterprise risk conditions should be continually monitored to ensure that they remain within acceptable levels. 3.6.1 describes the Check element, where the practitioner determines whether the intended activities accomplished objectives and to what extent.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204, 212, and 252 RIN 0750-AH02 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to establish a standard procedure for offerors to propose an alternative line item structure that reflects the offeror's business practices for selling and billing commercial items and initial provisioning spares for weapon systems DATES: Effective Date: September 20, 2011. FOR FURTHER INFORMATION CONTACT: Mr. Julian E. Thrash, 703-602-0310. SUPPLEMENTARY INFORMATION: I. Background DoD published a proposed rule in the Federal Register at 76 FR 21847 on April 19, 2011, to add DFARS language that provides offerors the opportunity to propose an alternative line item structure in solicitations for commercial items and initial provisioning spares. This DFARS change will allow offerors to provide information about their products that may not have been known to the Government prior to issuance of the solicitation. No public comments were received regarding the proposed rule. DoD identified the need to propose an alternative line item structure during process reviews and working group sessions that assessed destination-acceptance procedures. The process reviews performed by DoD cross-service working groups, which were chartered by the Defense Finance and Accounting System, examined issues causing problems in the receipt and acceptance phase for contract deliverables and payments. This group determined that the level of detail in the requirements description and line item structure is not always sufficient for delivery, payment, and subsequent inventory management of the items delivered. For example, the contract line item may be for a desktop computer, but the actual items delivered, invoiced, and inventoried may reflect a separate monitor, keyboard, and central processing unit. The resultant misalignment of transaction detail (i.e., contract line item, invoiced unit, delivery and inventory unit) is the cause of failures in the electronic processes of the DoD's business enterprise requiring manual intervention with potential delays in contractor payment.

3.1.3. 3.1.3 Review Management Procedures and Controls-Program Assessment The Contractor shall examine the management procedures that support security.

. FDA estimates that there are approximately 115,000 intrastate carriers, and based on DOT data, almost one million commercial drivers report intrastate travel. In reviewing the truck tonnage by commodity, approximately 12 percent of the intrastate shipments are of FDA-regulated food products. The average distance these products are shipped is 231 miles, which means many shipments are intrastate, especially in the larger western states. For some foods, distribution may be limited primarily to intrastate transportation, depending on the time of year and state. Many businesses have their own delivery trucks that are used intrastate, several use employee vehicles for deliveries, and many rent vehicles to deliver product. These vehicles are used to deliver all types of food products-refrigerated, cooked, as well as fresh food and produce, and grocery items. Some local firms pick up their own merchandise from warehouse facilities to stock their own locations.

Many of these "warehouses" (commonly referred to as "bin warehouses") may receive product via interstate transporter and subsequently deliver to a variety of intrastate retail customers via many different intrastate means. Data on the volume of foods that move in intrastate commerce are maintained by individual state Departments of Agriculture and by DOT. For example, from CA, LA, TX alone, DOT reports over 12 percent of intrastate truck tonnage is FDA-regulated products. Past traceback investigations provide examples of the need to regulate intrastate transport. For example, in 2003, there were two produce-associated outbreaks that occurred in CA from intrastate shipments. There were also two *Salmonella enteritidis* outbreaks in WI associated with intrastate shipments of eggs. Other foods, such as pasteurized milk, nearly all raw products, seafood, and sprouts, may be shipped either intrastate or interstate depending on the production or processing site. Most seafood consumed in FL is transported only intrastate, but in OK, most seafood is transported interstate. In 2002, there was an outbreak in NJ and FL linked to seafood. Intrastate records assisted us in pinpointing the portion of the Indian River, FL that was causing the problem. In reviewing egg tracebacks from 1996 to 2003, 35 percent of the tracebacks that resulted in farm investigations were intrastate. This past summer, the state of Oregon (OR) was able to stop a sprout-associated outbreak from becoming a serious one by tracing back to a WA sprouter just over the border from OR after some initial cases but before the *Salmonella* serotype had been identified. The sprouts were recalled. If the sprouter had been located in OR so that the sprouts were not transported interstate, it would have been problematic to a traceback investigation for FDA to be limited to records only from interstate transporters.

(C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because this system of records is compiled for investigative purposes and is exempt from the access provisions of subsections (d) and (f). (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. (24) System identifier and name. F036 AETC X, College Scholarship Program. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability but only to the extent that disclosure would reveal the (printed page 14744) identity of a confidential source. Therefore, portions of this system may be exempt pursuant to 5 U.S.C. 552a(k) (5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), and (e)(1). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. (A) From subsection (c)(3) and (d) and when access to accounting disclosures and access to or amendment of records would cause the identity of a confidential sources to be revealed. Disclosure of the source's identity not only will result in the Department breaching the promise of confidentiality made to the source but it will impair the Department's future ability to compile investigatory material for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, Federal contracts, or access to classified information. Unless sources can be assured that a promise of confidentiality will be honored, they will be less likely to provide information considered essential to the Department in making the required determinations. (B) From (e)(1) because in the collection of information for investigatory purposes, it is not always possible to determine the relevance and necessity of particular information in the early stages of the investigation. In some cases, it is only after the information is evaluated in light of other information that its relevance and necessity becomes clear. Such information permits more informed decision-making by the Department when making required suitability, eligibility, and qualification determinations. (25) System identifier and name. F032 AFCESA C, Civil Engineer System-Explosive Ordnance Records. (i) Exemption. Records maintained in connection with providing protective services to the President and other individuals under 18 U.S.C. 3056 , may be exempt pursuant to 5 U.S.C. 552a(k)(3) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3)

10. Estimate of the Time Required Before Preventive Action We estimated the time required before taking preventive action using FDA outbreak investigation information. We estimated the time required for a preventive action as the time that elapsed between the onset of the first reported illness and the first action taken by FDA or a commercial or state entity. In 11 of 26 traceback investigations considered from 2000 to 2003, an average of 78 days had elapsed between the time of the onset of the first illness in the outbreak and any initial preventive measure. The estimate of the time required for a preventive action may be overstated because for those investigations that

had entries reporting an initial action, but did not report a specific date of the action, we used the information entry date to approximate the date of the initial action. The information entry date is the date on which the initial action is recorded by FDA. Consequently, this procedure likely overestimates the time to preventive action because the information entry date is later than the date of the initial action it approximates, and in some cases may be significantly later than that date. Moreover, many investigations do not involve any preventive action that would limit the magnitude of the outbreak, because either the investigation lasts longer than the shelf life of the implicated food product (so that there is no longer any implicated food in circulation), or the implicated source of the outbreak is determined to be an isolated event with no possible preventive action that would limit the size of the outbreak. Because information from such observations is not used in the analysis, the resulting estimate of the investigation duration is likely to be shorter than what would otherwise be obtained. Based on the outbreak data used to create figure 2 of this document entitled 'Cumulative Distribution of the Fraction of Total Reported Illnesses by Outbreak Duration,' we estimate that between 15 and 18 percent of all illnesses were from outbreaks that lasted more than 78 days. This implies that, with an average of 2,081 reported illnesses per year, the faster tracebacks could potentially prevent up to a maximum of 312 to 374 (reported) illnesses per year. The average duration of outbreaks that last longer than 78 days is approximately 121 days, for an average net excess of 43 days (121 days minus 78 days). By dividing the maximum number of known illnesses per year, by the average duration of outbreaks that persist beyond 78 days, we estimate a maximum daily average of 8 to 9 illnesses that occur each day after the 78 day threshold.

33 || Educators' Association || || || || 9 | Access Control - Information Sharing | 33 33 | 33 33
 || || Automated Combinatorial Testing for Software || || || 11 | Conformance Verification for
 Access Control | 34 | 34 || Small and Medium Size Business Outreach || Policies Forensics for Web
 Services | 35 | 35 || Health Information Technology Se

to the extent such provisions have been identified and an exemption claimed for the original record, and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, and to preserve the confidentiality and integrity of Federal evaluation materials. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (21) System identifier and name. F033 AF B, Privacy Act Request Files. (i) Exemption. During the processing of a Privacy Act request, exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those 'other' systems of records are entered into this system, the Department of the Air Force hereby claims the same exemptions for the records from those 'other' systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record, and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this (printed page 14743) system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, and to preserve the confidentiality and integrity of Federal evaluation materials. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (22) System identifier and name. F051 AFJA E, Judge Advocate General's Professional Conduct Files. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2)

As with all of DoD programs, the Department intends to effectively oversee the CMMC Program and take the appropriate actions needed to manage its effective implementation. The phased implementation

plan described in § 170.3(e) was extended by six months and is intended to address ramp-up issues, provide time to train the necessary number of assessors, and allow companies the time needed to understand and implement CMMC requirements. **Small Business Entities Impacted** This rule will impact small businesses that do business with the Department of Defense, except those competing on contracts or orders that are exclusively for COTS items or when receiving contracts or orders valued at or below the micro-purchase threshold. According to the Federal Procurement Data System (FPDS) there is an average of 29,260 unique small business contractors: FY 2019 (31,189), FY 2020 (29,166) and FY 2021 (27,427). **Cost Assumptions and Analysis for CMMC** Complete details on CMMC requirements and associated costs, savings, and benefits of this rule are provided in the Regulatory Impact Analysis referenced in the preamble. Key Components of the model are described in §§ 170.14 through 170.24. (a) **Assumptions for the updated CMMC Program Cost Analysis** In estimating the public cost for a small DIB company to achieve CMMC compliance or certification at each CMMC level, DoD considered non-recurring engineering costs, recurring engineering costs, assessment costs, and affirmation costs for each CMMC Level. [62] These costs include labor and consulting. Estimates include size and complexity assumptions to account for organizational differences and how it handles Information Technology (IT) and cybersecurity: small entities have a less complex, less expansive operating environment and Information Technology (IT)/Cybersecurity infrastructure compared to larger DIB companies. small entities outsource IT and cybersecurity to an External Service Provider (ESP) entities (large or small) pursuing CMMC Level 2 self-assessment will seek consulting or implementation assistance from an ESP to either help them prepare for the assessment technically or participate in the assessment with the C3PAOs. Estimates do not include implementation (Non-recurring Engineering Costs (NRE)) or maintenance costs (Recurring Engineering (RE)) for requirements prescribed in current regulations. For CMMC Levels 1 and 2, cost estimates are based upon assessment, reporting and affirmation activities which a contractor will take to validate conformance with existing cybersecurity requirements from the FAR clause 52.204-21 (effective June 15, 2016) to protect FCI, and the DFARS clause 252.204-7012 which required contractor implementation of NIST SP 800-171 not later than December 31, 2017, to protect CUI. As such, costs estimates are not included for an entity to implement security requirements, maintain existing security requirements, or remediate a Plan of Action for unimplemented requirements.

, as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(1), (e)(4) (G) through (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(1) and (k)(5) . (iii) Reasons. (A) Exempted portions of this system contain information that has been properly classified under E.O. 12356 , and that is required to be kept secret in the interest of national defense or foreign policy. (B) Exempted portions of this system also contain information considered relevant and necessary to make a determination as to qualifications, eligibility, or suitability for access to classified information and was obtained by providing an express or implied assurance to the source that his or her identity would not be revealed to the subject of the record. (7) System identifier and name. N04060-1, Navy and Marine Corps Exchange Sales and Security Files. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(4)(G) through (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. Granting individuals access to information collected and maintained by these activities relating to the enforcement of criminal laws could interfere with orderly investigations, with orderly administration of justice, and possibly enable suspects to avoid detection or apprehension. Disclosure of this information could result in the concealment, destruction, or fabrication of evidence, and could also reveal and render ineffectual investigative techniques, sources, and methods used by these activities. (8) [Reserved] (9) System identifier and name. N05041-1, Inspector General (IG) Records. (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958 , as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Investigatory material compiled for law enforcement purposes may be exempt

pursuant to 5 U.S.C. 552a(k)(2)

means assets that process, store, or transmit FCI. FCI Assets are part of the Level 1 CMMC Assessment Scope and are assessed against all CMMC Level 1 requirements. (CMMC-custom term) Government Furnished Equipment (GFE) has the same meaning as government-furnished property as defined in 48 CFR 45.101. Industrial Control Systems (ICS) means a general term that encompasses several types of control systems, including supervisory control and data acquisition (SCADA) systems, distributed control systems (DCS), and other control system configurations such as Programmable Logic Controllers (PLC) often found in the industrial sectors and critical infrastructures. An ICS consists of combinations of control components (e.g., electrical, mechanical, hydraulic, pneumatic) that act together to achieve an industrial objective (e.g., manufacturing, transportation of matter or energy), as defined in NIST SP 800-82 R2 (incorporated by reference, see § 170.2). Information System (IS) is defined in NIST SP 800-171 Rev 2 (incorporated by reference, see § 170.2). Internet of Things (IoT) means the network of devices that contain the (printed page 89122) hardware, software, firmware, and actuators which allow the devices to connect, interact, and freely exchange data and information, as defined in NIST SP 800-172A (incorporated by reference, see § 170.2). Operational Technology (OT) means programmable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment). These systems or devices detect or cause a direct change through the monitoring or control of devices, processes, and events. Examples include industrial control systems, building management systems, fire control systems, and physical access control mechanisms, as defined in NIST SP 800-160v2 Rev 1 (incorporated by reference, see § 170.2). Organization-Defined means as determined by the OSA being assessed except as defined in the case of Organization-Defined Parameter (ODP). (CMMC-custom term) Organization-Defined Parameter (ODP) means selected enhanced security requirements contain selection and assignment operations to give organizations flexibility in defining variable parts of those requirements, as defined in NIST SP 800-172A (incorporated by reference, see § 170.2). Note 1 to ODP: For CMMC Level 3, the organization defining the parameters is the DoD. Organization Seeking Assessment (OSA) means the entity seeking to conduct, obtain, or maintain a CMMC assessment for a given information system at a particular CMMC Level. The term OSA includes all Organizations Seeking Certification (OSCs). (CMMC-custom term) Organization Seeking Certification (OSC) means the entity seeking to contract, obtain, or maintain CMMC certification for a given information system at a particular CMMC Level. An OSC is also an OSA. (CMMC-custom term) Out-of-Scope Assets

and maintained under all negotiated arrangements. FDA assumes that current business practices are the low-cost arrangement for the establishment and maintenance of records and does not revise its estimate of recordkeeping costs to account for higher coordination costs between transporters and nontransporters. (Comment 208) Some comments state that FDA's estimated cost per facility in the public warehousing sector is likely to be incorrect because of the apparent assumption that costs incurred would be similar for both a public warehouse and a wholesaler. The comments argue that, because wholesalers own a product, they are more knowledgeable about its contents and packaging than are warehouse facilities. The comment notes that a warehouse is a third party provider of warehousing, storage, and other value added services; does not have direct knowledge of where a product originates; and may not have full knowledge of the contents and packaging of a product, or of the product's next destination. Another comment states that the information asked for in the proposal is reasonable, but that this information will be difficult, costly, or impossible to obtain for public warehouse facilities. (Response) FDA acknowledges that warehouse facilities and wholesalers perform different functions. FDA has accounted for the differences in its cost estimates. The NAICS definition of the wholesale trade includes, "selling merchandise, generally without transformation to other business". The definition also characterizes wholesalers as normally operating from a warehouse or office (Ref. 27). In contrast, the NAICS defines the warehousing and storage sector as providing facilities to store goods but not sell the goods that they store. In addition, warehouse facilities may also provide logistical services for the goods that they store (Ref. 27). Although the warehouse and wholesaler functions are clearly different, FDA assumes that both kinds of facilities would have records giving an immediate previous source and an immediate subsequent recipient of the product. Because warehouse facilities do not take ownership of the products that they handle, they may not have specific information about the products and their packaging.

CMMC self-assessments and C3PAO assessments differ in several key ways: **Self-Assessment (Level 1

and Level 2 option)**: - Conducted internally by the organization - Affirmed by a senior official (CEO, CIO, or equivalent) - Lower cost (internal resources only) - Required for CMMC Level 1 and available as an option for some Level 2 contracts - Results entered into SPRS **C3PAO Certification Assessment (Level 2)**: - Conducted by an authorized C3PAO (Cyber AB-accredited) - Independent third-party verification - Higher cost (\$30K-\$150K+) - Required for Level 2 contracts specifying C3PAO assessment (Phase 2, November 2026) - Results in formal CMMC certification (valid 3 years) The contract will specify which type of assessment is required. During Phase 1 (current), most contracts accept self-assessments. Phase 2 will introduce C3PAO certification requirements.

The Department of Health and Human Services (HHS or Department) has examined the effects of this proposed rule under Executive Order (E.O.) 12866, Regulatory Planning and Review, [931] E.O. 13563 , Improving Regulation and Regulatory Review, [932] E.O. 14094 , Modernizing Regulatory Review, [933] the Regulatory Flexibility Act [934] (RFA), the Unfunded Mandates Reform Act of 1995 [935] (UMRA), and E.O. 13132 on Federalism. [936] E.O.s 12866 and 13563 direct the Department to assess all costs and benefits of available regulatory alternatives and, when regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety, and other advantages; distributive effects; and equity). The proposed rule meets the criteria as significant under section 3(f)(1) of E.O. 12866 , as amended by E.O. 14094 . The RFA requires us to analyze regulatory options that would minimize any significant effect of a rule on small entities. As discussed in greater detail below, this analysis concludes, and the Secretary certifies, that the notice of proposed rulemaking (NPRM), if adopted, would not result in a significant economic effect on a substantial number of small entities. The UMRA (section 202(a)) generally requires us to prepare a written statement, which includes an assessment of anticipated costs and benefits, before proposing any rule that includes any Federal mandate that may result in the expenditure by State, local, and Tribal governments, in the aggregate, or by the private sector, of \$100,000,000 or more (adjusted annually for inflation) in any 1 year. [937] The current threshold after adjustment for inflation is \$183 million, using the most current (2024) Implicit Price Deflator for the Gross Domestic Product. UMRA does not address the total cost of a rule. Rather, it addresses certain categories of cost, mainly Federal mandate costs resulting from imposing enforceable duties on State, local, or Tribal governments or the private sector; or increasing the stringency of conditions in, or decreasing the funding of, State, local, or Tribal governments under entitlement programs. This proposed rule, if adopted, would impose mandates that would result in the expenditure by State, local, and Tribal governments, in the aggregate, or by the private sector, of more than \$183 million in any one year. The impact analysis in this proposed rule addresses such effects both qualitatively and quantitatively. Each covered entity and business associate (collectively, regulated entity), including government entities that meet the definition of covered entity (e.g.,

(D) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (E) From subsection (e)(2) because in a criminal or other law enforcement investigation, the requirement that information be collected to the greatest extent possible from the subject individual would alert the subject as to the nature or existence of the investigation and thereby present a serious impediment to effective law enforcement. (F) From subsection (e)(3) because the requirement that individuals supplying information be provided with a form stating the requirements of subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (G) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from access provisions of subsection (d), making these subsections not applicable. (H) From subsections (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (I) From subsection (e)(5) because the requirement that records be maintained with attention to accuracy, relevance, timeliness, and completeness would unfairly hamper the investigative process. It is the nature of law enforcement for investigations to uncover the commission of illegal acts at diverse stages. It is frequently impossible to determine

initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. (J) From subsection (e)(8) because the notice requirements of this provision could present a serious impediment to criminal law enforcement by revealing investigative techniques, procedures, and the existence of confidential investigations. (K) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (L) From subsection (g) because portions of this system of records are compiled for law enforcement purposes and have been exempted from the access provisions of subsections (d) and (f). (17) System identifier and name. A0195-2c USACIDC DoD, DoD Criminal Investigation Task Force (CITF) Files. (i) Exemption.

a. Marking and Identifying CUI Comment: Multiple commenters asked for clarification regarding definition, marking, and identification of CUI as related to CMMC requirements and DFARS clause 252.204-7021. One commenter asked if the definition of DoD CUI applies to the CUI required to be safeguarded under the CMMC clause. Another asked if DFARS clause 252.204-7021 includes information that requires protection under DFARS clause 252.204-7012. One commenter requested that the Department confirm that, under CMMC, contractors will only be responsible for protecting CUI that is clearly marked upon receipt from the Department and created by contractors. Response: If the contract includes a CMMC Level requirement, contractors will be required to protect FCI and CUI, as applicable, through fulfillment of the designated CMMC Level security requirements. CMMC does not in any way change the DoD requirements regarding the definition, marking, and protection of CUI. If DFARS clause 252.204-7012 applies, contractors are required to safeguard covered defense information in accordance with the terms and conditions of the clause and contract, which includes information developed in support of the contract. CMMC does not change these requirements. b. Relationship of FCI and CUI to the CMMC Requirements Comment: One commenter suggested that the inclusion of FCI in CMMC needs significant clarification. Others asked if FCI references within the CMMC Model [1.0] and nonpublic DoD information references in Department of (printed page 89069) Defense Instruction (DoDI) 8582.01 [18] are the same type of information, and if DoDI 8582.01 is the definitive DoD policy for FCI and DoD standards regarding the requirements under FAR clause 52.204-21. Response: The CMMC Program requirements for Level 1 will apply when the contract effort requires contractors to process, store, or transmit FCI on its unclassified information system. If CUI is processed, stored, or transmitted on a contractor information system, a higher level of CMMC compliance or certification is required. The CMMC Level required to protect CUI (i.e., CMMC Level 2 Self-Assessment as described in § 170.16, CMMC Level 2 Certification Assessment as described in § 170.17, or CMMC Level 3 Certification Assessment as described in § 170.18) is determined by the Department based upon the sensitivity of the CUI and will be identified in the solicitation. The CMMC Program uses the definitions of FCI from FAR 4.1901 and CUI from 32 CFR 2002

Many different types of people use ICAT for a variety of purposes. System administrators and computer security officers use ICAT to identify the known vulnerabilities (and patch information) associated with the software on critical systems. Law enforcement can use ICAT in forensics activities to determine the set of possible vulnerabilities that a hacker might have used to penetrate a system. Computer security researchers use ICAT to identify sets of vulnerabilities that have particular characteristics of interest. Auditors can use ICAT to check to see if particular vulnerabilities have been patched in audited systems.

Control PD-200901022: nal structure and implementation detail of the assessment object. This type of testing is conducted using a functional specification for mechanisms and a high-level process description for activities. Basic testing provides a level of understanding of the security safeguards necessary for determining whether the safeguards are implemented and free of obvious errors. | | | Focused | Test methodology (also known as gray box testing) that assumes some knowledge of the internal structure and implementation detail of the assessment object. This type of testing is conducted using a functional specification and limited system architectural information (e.g., high-level design) for mechanisms and a high-level process description and high-level description of integration into the operational environment for activities. Focused testing provides a level of understanding of the security safeguards necessary for determining whether the safeguards are implemented and free of obvious errors and whether there are increased grounds for confidence that the safeguards are implemented correctly and operating as intended .

(iii) Some access requirements for RD and FRD exceed the requirements for NSI. Due to the unique

national security implications of RD and FRD, and to facilitate maintaining consistency of codified requirement, they are not repeated in the baseline of this rule, but may be applied through specific contract requirements. (iv) When RD is transclassified as TFNI, it is safeguarded as NSI. Such information will be labeled as TFNI. The label TFNI will be included on (printed page 83361) documents to indicate it is exempt from automatic declassification as specified in 10 CFR part 1045 , the AEA, E.O. 13526 , and 32 CFR part 2001 . (2) Unauthorized disclosures. Contractors will report all unauthorized disclosures involving RD, FRD and TFNI information to the CSA. (3) International requirements. The AEA provides for a program of international cooperation to promote common defense and security and to make available to cooperating nations the benefits of peaceful applications of atomic energy as widely as expanding technology and considerations of the common defense and security will permit. (i) Information controlled in accordance with the AEA, RD, and FRD may be shared with another nation only under the terms of an agreement for cooperation. The disclosure by a contractor of RD and FRD will not be permitted until an agreement is signed by the United States and participating governments, and disclosure guidance and security arrangements are established. (ii) RD and FRD will not be transmitted to a foreign national or regional defense organization unless such action is approved and undertaken under an agreement for cooperation between the United States and the cooperating entity and supporting statutory determinations, as prescribed in the AEA. (4) Personnel security clearance and access. Only the DOE, the NRC, the DoD, and the National Aeronautics and Space Agency can grant access to RD and FRD that is under their cognizance. Access to RD and FRD must be granted in accordance with the AEA. Baseline requirements for access to RD and FRD are codified in specific DoD, DOE, NRC, and the National Aeronautics and Space Agency directives and regulations. In addition, need-to-know and other restrictions on access apply. (5) Classification and declassification. (i) All persons with access to RD and FRD must receive initial and periodic refresher training as required under §.1045.120 10 CFR. The training must include the following information: (A) What information is potentially RD and FRD. (B) Matter that potentially contains RD or FRD must be reviewed by an RD derivative classifier to determine whether it is RD or FRD. (C) The DOE must review matter that potentially contains RD or TFNI for public release and DOE or DoD must review matter that potentially contains FRD for public release. (D) RD derivative classification authority is required to classify or upgrade matter containing RD or FRD, or to downgrade the level of matter containing RD or FRD.

(iii) A routine use applies. Another major exception to the ·no disclosure without consent· rule is the routine use exception. The Privacy Act allows federal agencies to publish routine use exceptions to the Privacy Act. Some routine uses are Army specific, DOD specific, and Governmentwide. Routine uses exceptions are listed in the Privacy Act system of records notice(s) applicable to the Privacy Act records in question. The Army and other agencies' system of records notices may be accessed at the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy> . (2) The approved twelve exceptions to the Privacy Act ·no disclosure without consent· rule are listed at appendix C of this part. (b) Disclosing records to other DOD components and to federal agencies outside the DOD. (1) The twelve Privacy Act exceptions referred to in appendix C of this part are available to other DOD components and to federal agencies outside the DOD as exceptions to the Privacy Act's ·no disclosure without consent· rule, with the exception of the FOIA exception. The FOIA is not an appropriate mechanism for providing information to other DOD components and to federal agencies outside the DOD. (2) A widely used exception to requests for information from local and state government agencies and federal agencies not within the DOD is the routine use exception to the Privacy Act. (3) The most widely used exception to requests for information from other DOD components is the ·intra-agency need to know· exception to the Privacy Act. Officers and employees of the DOD who have an official need for the records in the performance of their official duties are entitled to Privacy Act protected information. Rank, position, or title alone does not authorize access to personal information about others. An official need for the information must exist before disclosure. (4) For the purposes of disclosure and disclosure accounting, the Department of Defense (DOD) is considered a single agency. (c) Disclosures under AR 25-55, the Freedom of Information Act (FOIA) Program. (1) Despite Privacy Act protections, all records must be disclosed if the Freedom of Information Act (FOIA) requires their release. The FOIA requires release unless the information is exempted by one or more of the nine FOIA exemptions. (2) Required release under the FOIA. The following are examples of personal information that is generally not exempt from the FOIA; therefore, it must be released to the public, unless covered by paragraphs (d)(2) and (d)(3) of this section. The following list is not all inclusive: (i) Military Personnel· (A) Rank, date of rank, active duty entry date, basic pay entry date, and gross pay (including base pay, special pay, and

all allowances except Basic Allowance for Housing); (B) Present and past duty assignments, future stateside assignments; (C) Office/unit name, duties address and telephone number (DOD policy may require withholding of this information in certain circumstances);

· Communications 24. Which of the following topics have been addressed by your security awareness program via training courses, events, or other communications in the past 1-2 years? Check all that apply. · Communications and marketing

Section 170.12 addresses the roles and responsibilities of a CMMC Provisional Instructor (PI) and CMMC Certified Instructor (CCI) to teach CMMC assessor candidates. Candidate PIs and CCIs are trained and tested per the requirements set forth in § 170.12(c). Section 170.12(c) also provides candidate PIs and CCIs with the requirements to obtain and maintain designation or certification (as applicable), compliance with Accreditation Body policies, work activity exclusions, confidentiality (printed page 83101) expectations, non-disclosure clause, non-public training related information, forbidden consulting services, and reporting requirements. Section 170.13-CMMC Certified Professional (CCP) Section 170.13 addresses the roles and responsibilities of a CMMC Certified Professional (CCP) required to provide advice, consulting, and recommendations to clients. The CAICO trains and tests candidate CCPs per the requirements set forth in § 170.13(b) with CCP certification issued upon successful completion. A CCP can participate on CMMC Level 2 certification assessments with CCA oversight, however CCAs are responsible for making final assessment determinations for a CMMC Status of Conditional or Final Level 2 (C3PAO). A list of CCP requirements is provided for obtaining and maintaining certification, compliance with Accreditation Body policies, completion of a Tier 3 background investigation or equivalent, sharing assessment specific information, and reporting requirements. Section 170.14-CMMC Model Section 170.14 addresses the structure, security requirement contents, organization, sourcing, and numbering of the security requirements that comprise the CMMC Model. It also provides an overview of the assessment process. The CMMC Model consists of three (3) levels, each containing security requirements taken directly from existing regulations and guidelines. Firstly, § 170.14(2) defines CMMC Level 1 as the 15 security requirements listed in the FAR clause 52.204-21(b)(1). Secondly, § 170.14(3) defines CMMC Level 2 as the 110 security requirements from the NIST SP 800-171 R2. Lastly, § 170.14(4) defines CMMC Level 3 as 24 selected security requirements from the NIST SP 800-172 Feb2021. The CMMC security requirements are organized into domains following the approach taken in NIST SP 800-171 R2. The numbering of the CMMC security requirements, addressed in § 170.14(c)(1), is of the form DD.L#-REQ where the 'DD' is the two-letter domain abbreviation, the 'L#' is the CMMC Level, and the 'REQ' is based directly on the numbering in the source. Assessment criteria for these security requirements, as described in § 170.14(d), is based on security requirement assessment guidance provided in NIST SP 800-171A Jun2018 and NIST SP 800-172A Mar2022. Section 170.15-CMMC Level 1 Self-Assessment and Affirmation Requirements

ries in batches instead of on an ongoing basis. 4 - GLYPH<c=31,font=/APONEK+Webdings> Remote Access Software. Remote access is often granted and secured through virtual private networking (VPN). VPN systems typically log successful and failed login attempts, as well as the dates and times each user connected and disconnected, and the amount of data sent and received in each user session. VPN systems that support granular access control, such as many Secure Sockets Layer (SSL) VPNs, may log detailed information about the use of resources. -

GLYPH<c=31,font=/APONEK+Webdings> Web Proxies. Web proxies are intermediate hosts through which Web sites are accessed. Web proxies make Web page requests on behalf of users, and they cache copies of retrieved Web pages to make additional accesses to those pages more efficient. Web proxies can also be used to restrict Web access and to add a layer of protection between Web clients and Web servers. Web proxies often keep a record of all URLs accessed through them. -

GLYPH<c=31,font=/APONEK+Webdings> Vulnerability Management Software. Vulnerability management software, which includes patch management software and vulnerability assessment software, typically logs the patch installation history and vulnerability status of each host, which includes known vulnerabilities and missing software updates. 5 Vulnerability management software may also record additional information about hosts' configurations. Vulnerability management software typically runs occasionally, not continuously, and is likely to generate large batches of log entries. -

GLYPH<c=31,font=/APONEK+Webdings> Authentication Servers. Authentication servers, including directory servers and single sign-on servers, typically log each authentication attempt, including its origin, username, success or failure, and date and time.

(ix) Review, if applicable, ongoing Computer Matching Agreements. The Defense Data Integrity Board approves Computer Matching Agreements for 18 months, with an option to renew for an additional year. This additional review will ensure that the requirements of the Privacy Act, Office of Management and Budget guidance, local regulations, and the requirements contained in the Matching Agreements themselves have been met. (7) All DA personnel will-

- (i) Take appropriate actions to ensure personal information contained in a Privacy Act system of records is protected so that the security and confidentiality of the information is preserved;
- (ii) Not disclose any personal information contained in a Privacy Act system of records except as authorized by 5 U.S.C. 552a, DOD 5400.11-R, or other applicable laws. Personnel willfully making a prohibited disclosure are subject to possible criminal penalties and/or administrative sanctions; and
- (iii) Report any unauthorized disclosures or unauthorized maintenance of new Privacy Act systems of records to the applicable activity's Privacy Act Official.

(8) Heads of Joint Service agencies or commands for which the Army is the Executive Agent or the Army otherwise provides fiscal, logistical, or administrative support, will adhere to the policies and procedures in this part. (9) Commander, Army and Air Force Exchange Service, will supervise and execute the Privacy Program within that command pursuant to this part. (10) Overall Government-wide responsibility for implementation of the Privacy Act is the Office of Management and Budget. The Department of Defense is responsible for implementation of the Act within the armed services. The Privacy Act also assigns specific Government-wide responsibilities to the Office of Personnel Management and the General Services Administration. (11) Government-wide Privacy Act systems of records notices are available at <http://www.defenselink.mil/privacy>.

(e) Legal Authority. (1) Title 5, United States Code, Section 552a, as amended, The Privacy Act of 1974. (2) Title 5, United States Code, Section 552, The Freedom of Information Act (FOIA). (3) Office of Personnel Management, Federal Personnel Manual (5 CFR parts 293, 294, 297, and 7351). (4) OMB Circular No. A-130, Management of Federal Information Resources, Revised, August 2003. (5) DOD Directive 5400.11, Department of Defense Privacy Program, November 16, 2004. (6) DOD Regulation 5400.11-R, Department of Defense Privacy Program, August 1983. (7) Title 10, United States Code, Section 3013, Secretary of the Army. (8) Executive Order No. 9397, Numbering System for Federal Accounts Relating to Individual Persons, November 30, 1943. (9) Public Law 100-503, the Computer Matching and Privacy Act of 1974. (10) Public Law 107-347, Section 208, Electronic Government (E-Gov) Act of 2002. (11) DOD Regulation 6025.18-R, DOD Health Information Privacy Regulation, January 24, 2003. § 505.2 General provisions. (a) Individual privacy rights policy

) govern the agency's ability to disclose information to the public. For example, section 301 of the FD&C Act prohibits any person from using to his own advantage or revealing, other than to the Secretary or other officers or employees of the Department, or to the courts, any information acquired under authority of section 414 and 704 concerning any method or process which as a trade secret is entitled to protection. Furthermore, the records provisions in the Bioterrorism Act recognize that FDA may obtain trade secret or confidential information and direct the Secretary to take appropriate measures to ensure that there are in effect effective procedures to prevent the unauthorized disclosure of [such information]. (21 U.S.C. 414(c)). FDA is planning to reemphasize (printed page 71591) in instructions to FDA personnel the importance of current protections and legal requirements against the unauthorized disclosure of any trade secret or confidential information that is obtained. Therefore, FDA disagrees that a manufacturer would be harmed by disclosing ingredient information to FDA. Moreover, the FD&C Act currently requires manufacturers to disclose the ingredients they use to the public on food labels. One comment notes that section 403(i)(2) of the FD&C Act excludes spices, flavorings, and some colors from the label requirement. The exemption in section 403(i)(2) of the FD&C Act from disclosing specific spices, flavorings, and colors to the public on the label does not prohibit FDA from obtaining this information under the Bioterrorism Act. As previously discussed, if this information is legally protected from public disclosure, FDA will not release it to the public.

(iv) Statements, written or audio, of contractor employees describing what they witnessed or experienced in connection with the contractor's performance of the contract. Government data means any information (including metadata), document, media, or machine-readable material regardless of physical form or characteristics that is created or obtained by the Government, or a contractor on behalf of the Government, in the course of official Government business. Government-related data means any information, document, media, or machine-readable material regardless of physical form or characteristics that is created or obtained by a contractor through the storage, processing, or communication of Government data. Government-related data does not include-

- (1) A contractor's business records (e.g., financial records, legal records) that do not incorporate Government

data; or (2) Data such as operating procedures, software coding or algorithms that are not primarily applied to the Government data. Information means any communication or representation of knowledge, such as facts, data, or opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, electronic, or audiovisual forms (see Office of Management and Budget (OMB) Circular No. A-130, Managing Information as a Strategic Resource). Information and communications technology (ICT) means information technology and other equipment, systems, technologies, or processes, for which the principal function is the creation, manipulation, storage, display, receipt, or transmission of electronic data and information, as well as any associated content. Examples of ICT include but are not limited to the following: computers and peripheral equipment; information kiosks and transaction machines; telecommunications equipment; telecommunications services; customer premises equipment; multifunction office machines; computer software; applications; websites; electronic media; electronic documents; Internet of Things (IoT) devices; and operational technology. Information system means a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information (44 U.S.C. 3502(8)). Information resources as used in this definition, includes any ICT. Media means physical devices or writing surfaces including, but not limited to, magnetic tapes, optical disks, magnetic disks, large-scale integration memory chips, and printouts onto which information is recorded, stored, or printed within an information system (NIST SP 800-53). (b) Applicability. The requirements of this clause shall only apply to aspects of a Federal information system (FIS) that involve cloud computing services. (c) Cloud computing security requirements.

3.3.5 | Encryption and Integrity Protection... 3.3.5 Encryption and Integrity Protection SSL VPNs use the underlying SSL protocol to protect the confidentiality of data using encryption and to provide data integrity (ensuring that the data has not been modified).

A new solicitation provision at FAR 52.204-WW, Notice of Controlled Unclassified Information Requirements, is prescribed for use in solicitations that contain the new clause at FAR 52.204-XX or the new clause at FAR 52.204-YY. This provision provides a notice to offerors that agencies will provide agency procedures on handling CUI during the solicitation phase if handling CUI is necessary to prepare an offer. The notice also advises offerors that contractor bid or proposal information, proprietary business information, or contractor-attributable information must be properly marked to ensure adequate protection of their information. The provision also advises offerors that they should notify the contracting officer if there appears to be unmarked or mismarked CUI or an incident related to CUI handled by the offeror during the solicitation phase. When the contract does not identify CUI, the new contract clause at FAR 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information, is used in lieu of the CUI clause. Similar to the solicitation provision, this clause requires the contractor to notify the Government if there appears to be unmarked or mismarked CUI or a suspected CUI incident related to information handled by the contractor in performance of the contract. This clause requires the contractor to properly mark proprietary business information or contractor-attributable information to ensure adequate protection. The new solicitation provision and the new contract clauses all forbid an offeror or contractor from using Government-provided information for its own purposes, whether or not the information is marked as CUI, unless the information is in the public domain, or unless the information is lawfully made available to the offeror or contractor by someone other than the Government. B. Benefits 1. Uniform Cybersecurity Hygiene Baseline Establishing uniform requirements for how the acquisition workforce and Federal contractors manage CUI will significantly improve the Government and Federal contractors' ability to protect Federal information and information systems from criminals and our adversaries. Absent the uniform approach proposed in this rule, agencies will continue to employ ad hoc, agency-specific policies to manage this information, an approach that can cause agencies to mark and handle information inconsistently and inefficiently. While waivers may be applied in some circumstances, this rule is intended to establish a Governmentwide baseline that will lead to more effective implementation of protections for this sensitive information by the acquisition workforce and contractors. More effective implementation of requirements for identifying and marking CUI will reduce scenarios in which contractors may not realize the information that they are handling is sensitive information that must be safeguarded. 2. Protection From Potential Financial Impacts of CUI Incidents

(A) From subsection (c)(3) because the release of accounting of disclosure would inform a subject that he or she is under investigation. This information would provide considerable advantage to the

subject in providing him or her with knowledge concerning the nature of the investigation and the coordinated investigative efforts and techniques employed by the cooperating agencies. This would greatly impede OIG's criminal law enforcement. (B) From subsection (c)(4) and (d), because notification would alert a subject to the fact that an open investigation on that individual is taking place, and might weaken the on-going investigation, reveal investigatory techniques, and place confidential informants in jeopardy. (C) From subsection (e)(1) because the nature of the criminal and/or civil investigative function creates unique problems in prescribing a specific parameter in a particular case with respect to what information is relevant or necessary. Also, due to OIG's close liaison and working relationships with other Federal, state, local and foreign country law enforcement agencies, information may be received which may relate to a case under the investigative jurisdiction of another agency. The maintenance of this information may be necessary to provide leads for appropriate law enforcement purposes and to establish patterns of activity which may relate to the jurisdiction of other cooperating agencies. (D) From subsection (e)(2) because collecting information to the fullest extent possible directly from the subject individual may or may not be practical in a criminal and/or civil investigation. (E) From subsection (e)(3) because supplying an individual with a form containing a Privacy Act Statement would tend to inhibit cooperation by many individuals involved in a criminal and/or civil investigation. The effect would be somewhat adverse to established investigative methods and techniques. (printed page 14800) (F) From subsection (e)(4) (G) through (I) because this system of records is exempt from the access provisions of subsection (d). (G) From subsection (e)(5) because the requirement that records be maintained with attention to accuracy, relevance, timeliness, and completeness would unfairly hamper the investigative process. It is the nature of law enforcement for investigations to uncover the commission of illegal acts at diverse stages. It is frequently impossible to determine initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. (H) From subsection (e)(8) because the notice requirements of this provision could present a serious impediment to law enforcement by revealing investigative techniques, procedures, and existence of confidential investigations.

ngle sign-on; and - Privacy technologies, including a privacy framework, privacy reference architecture, privacy infrastructure, anonymity and credentials, and specific privacy-enhancing technologies. In the past year, NIST continued to support the EAC in finalizing changes to the Voluntary Voting System Guidelines (VVSg) 1.1. These changes sought to improve the auditability of voting systems, provide greater software integrity protections, expand and improve access-control requirements, and help ensure that cryptographic security mechanisms are implemented properly. The EAC approved these updates to the VVSg in March 2015. In addition, NIST completed a set of draft test assertions for the security requirements in the VVSg. This included test assertions in the

As an example computing how compressed preliminary investigation and decision making times affect the benefits from faster tracebacks, we estimate the duration of the preliminary and decision making parts of the outbreak investigation to currently be approximately 55 days (i.e., the difference between 78 days for an initial preventive action and 33 days for the traceback investigation). If we assume a 50 percent reduction in the times for the preliminary and decision making components of an outbreak investigation, then a 10-day reduction in traceback times would result in preventive measures taken after approximately 56 days (28 days, rounding up, for the preliminary and decision making investigations plus 28 days for a traceback investigation) compared with the current 78 day duration. For a 75 percent reduction in the duration of the initial parts of an outbreak investigation, a 10-day reduction in traceback times would result in preventive measures being taken after approximately 42 days (14 days for preliminary and decision making investigations plus 28 days for a traceback investigation) compared with the current 78 days. b. Records retention requirements of 6 months, 12 months, and 24 months based on three NIST definitions . Many comments suggested that product shelf lives as defined by the NIST should determine which product records would be subject to retention requirements of 6 months, 12 months, and 24 months. We estimate a negligible reduction in costs (which we estimate to be zero) and benefits associated with reducing retention times in the final rule. The provision specifying the shorter retention requirements of 6 months, 12 months, and 24 months may result in the destruction of records earlier than would be the case for the longer retention requirements. While we estimate the reduction in benefits from the reduced retention times to be negligible, we explain the logic behind the perverse incentive for the early destruction of records, and its potential impact on traceback performance. The benefits from the records access requirements cannot be realized without the records retention requirements. If

records no longer exist, there is nothing for FDA to access.

When a Government Contracting Activity (GCA), an element of an agency that has authority regarding acquisition or grant functions, awards a contract that has been determined to require access to classified information, the contract is considered to be a classified contract. The GCA checks with its applicable CSA to determine if the awarded legal entity already has an entity eligibility determination (also referred to as a facility security clearance (FCL)). GCAs will ordinarily include enough lead-time in the acquisition cycle to accomplish all required security actions. In many instances, advanced planning can ensure that access to classified information will not be required in the pre-award process. This would preclude processing an entire bidder list for FCLs. When access to classified information is not a factor in the pre-award phase, but will be required for contract performance, only the successful bidder or offeror will be processed for an FCL. Before an entity can have access to classified information during its contract performance, it must have an FCL. If the legal entity does not already have an FCL when awarded a classified contract, a GCA must sponsor the entity for an FCL. Or, an entity already part of the NISP (i.e., a prime contractor) may sponsor another entity in order to subcontract part of its classified business. To sponsor an entity, the GCA or prime contractor puts in a request, often referred to as a sponsorship letter, to the appropriate CSA for the entity to access classified information in connection with a legitimate government requirement, which may include a foreign government requirement. With an approved FCL, an entity is then eligible for access to information classified at the level of the FCL (i.e., TOP SECRET, SECRET or CONFIDENTIAL) when competing for a classified contract. Among other requirements, an entity must have sponsorship based on a valid government requirement for access to classified information. The USG agency sponsoring an entity for an FCL must include the applicable security requirements clause or equivalent in the contract (e.g., for DoD this is the Federal Acquisition Regulation (FAR) 52.204-2 Security Requirements, or the terms and conditions of a grant award under 2 CFR part 200.210) to require compliance with the NISPOM. A GCA provides the security requirements for a classified contract in a contract security classification specification as part of the contract. For DoD, the DD form 254, Department of Defense Contract Security Classification Specification, OMB Control number 0704-0567, is part of the classified contract and provides the contractor (or a subcontractor) with security requirements and the classification (printed page 83302) guidance necessary to execute a specific classified contract. See <https://www.esd.whs.mil/Portals/54/Documents/DD/forms/dd/dd0254.pdf> and available at <https://www.dcsa.mil/is/nccs/>.

194. Where an application developer meets the HIPAA Rules' definition of health care provider and engages in standard electronic transactions, such as billing an insurance company for its services, it is a covered entity for the purposes of the HIPAA Rules, including the Security Rule. Where an application developer is not regulated under the HIPAA Rules, other Federal laws may apply to the application developer or the application, such as the FTC Act. See, e.g., FTC Act (codified at 15 U.S.C. 41-58). Back to Citation 195. See, e.g., Kea Turner, et al., Sharing patient-generated data with healthcare providers: findings from a 2019 national survey, Journal of the American Medical Informatics Association, p. 371-376 (Nov. 12, 2020), <https://doi.org/10.1093/jamia/ocaa272> ; Accenture Federal Services, Conceptualizing a Data Infrastructure for the Capture, Use, and Sharing of Patient-Generated Health Data in Care Delivery and Research through 2024, The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, p. 5 (Jan. 2018), https://www.healthit.gov/sites/default/files/onc_pghd_final_white_paper.pdf ; see also Jolaade Kalinowski, et al., Smart device ownership and use of social media, wearable trackers, and health apps among Black women with hypertension in the United States, JMIR Cardio (pre-print), <https://preprints.jmir.org/preprint/59243> . Back to Citation 196. See Conceptualizing a Data Infrastructure for the Capture, Use, and Sharing of Patient-Generated Health Data in Care Delivery and Research through 2024, supra note 195, p. 1; Asos Mahmood, et al., mHealth Apps Use and Their Associations With Healthcare Decision-Making and Health Communication Among Informal Caregivers: Evidence From the National Cancer Institute's Health Information National Trends Survey, American Journal of Health Promotion, p. 40-52 (Jan. 2024), <https://journals-sagepub-com.hhsnih.idm.oclc.org/doi/10.1177/08901171231202861> . Back to Citation 197. See 88 FR 75191 (Nov. 1, 2023); Ritu Agarwal, et al., Augmenting physicians with artificial intelligence to transform healthcare: Challenges and opportunities, Journal of Economics & Management Strategy, p. 360-374 (Mar. 2024), <https://onlinelibrary-wiley-com.hhsnih.idm.oclc.org/doi/10.1111/jems.12555> ; Becca Beets, et al., Surveying Public Perceptions of Artificial Intelligence in Health Care in

the United States: Systematic Review, Journal of Medical Internet Research (2023), <https://doi.org/10.2196/40337>. Back to Citation 198. Michael E. Matheny, et al., Artificial Intelligence in Health Care: A Report from the National Academy of Medicine, Journal of the American Medical Association, p. 509-10 (2020), <https://jamanetwork.com/hhsnihi.dcm.oclc.org/journals/jama/fullarticle/2757958>. Back to Citation 199. 2023 HIMSS Healthcare Cybersecurity Survey, Healthcare Information and Management Systems Society, p. 19 (Mar. 1, 2024),

(iii) A statement that the information being denied does not contain meaningful portions that are reasonably segregable in the case of appeals for total denial of records. (iv) The requester's right to judicial review. (g) Consultation. (1) Final denial of access involving issues not previously resolved or that the DoD Component knows to be inconsistent with rulings of other DoD Components ordinarily should not be made before consultation with the DoD Office of the General Counsel. (2) Tentative decisions to deny records that raise new or significant legal issues of potential significance to other Government agencies shall be discussed with the DoD Office of the General Counsel. § 286.21 Judicial actions. (a) General. (1) This paragraph states current legal and procedural rules for the convenience of the reader. The statements of rules do not create rights or remedies not otherwise available, nor do they bind the Department of Defense to particular judicial interpretations or procedures. (2) A requester may seek an order from a U.S. District Court to compel release of a record after administrative remedies have been exhausted; i.e., when the requester has filed an administrative appeal from the denied access to a record by the Head of the DoD Component or an appellate designee, or when the DoD Component has failed to respond within the time limits prescribed by the FOIA and in this part. (b) Venue. The requester may bring suit in the U.S. District Court in the district in which the requester resides, the district where the requester's place of business is located, the district in which the record is located, or the District of Columbia. (c) Burden of proof. The burden of proof is on the DoD Component to justify its refusal to provide a record. The court shall evaluate the case de novo (anew) and may elect to examine any requested record in camera (in private) to determine whether the denial was justified. (d) Actions by the court. (1) The U.S. District Court for the District of Columbia has ruled that, when the DoD Component has failed to make a determination within the statutory time limits but can demonstrate due diligence in exceptional circumstances, to include negotiating with the requester to modify the scope of their request, the court may retain jurisdiction and allow the Component additional time to complete its review of the records (Department of Justice FOIA Update Web site). The Component must request that the Court retain jurisdiction by seeking an Open America stay (Department of Justice FOIA Update Web site). (2) If the Court determines that the plaintiff substantially prevails, it may require the United States to pay reasonable attorney fees and other litigation costs.

Although this regulation is costly, we do not expect it to substantially affect national productivity, growth, jobs, or full employment. The total costs will be small relative to the economy, and will be offset by benefits. The improved ability to respond to, and contain, serious adverse health consequences means less illness and fewer sick days taken by employees, and lower adjustment costs by firms that would otherwise need to hire replacement employees. Exports This rule requires additional records to be kept throughout the production and distribution chain for food. The additional recordkeeping costs will increase the total costs of production and distribution for all of the regulated products, including products sold within the United States and across national borders. These increased costs will be largely passed on to consumers in the form of higher prices, which will tend to reduce the quantity demanded of the regulated products. The increased prices of United States exports could reduce the quantity of United States exports demanded, particularly in comparison with exports from countries that do not implement similar recordkeeping regulations. We expect this effect to be insignificant, because under the final rule, the increases in the price of United States exports (and resulting decreases in quantity demanded) will be quite small. VII. SBREFA SBREFA (Public Law 104-121) defines a major rule for the purpose of congressional review as having caused or being likely to cause one or more of the following: an annual effect on the economy of \$100 million or more; a major increase in costs or prices; significant adverse effects on competition, employment, productivity, or innovation; or significant adverse effects on the ability of United States-based enterprises to compete with foreign-based enterprises in domestic or export markets. In accordance with SBREFA, OMB has determined that this final rule is a major rule for the purpose of congressional review. (printed page 71649) VIII. Paperwork Reduction Act of 1995 This final rule contains information collection

requirements that are subject to review by OMB under the Paperwork Reduction Act of 1995 (PRA) (44 U.S.C. 3501-3520). The title, description, and respondent description of the information collection requirement are shown below with an estimate of the annual recordkeeping burden. Included in the estimate is the time for reviewing instructions, searching existing data sources, gathering and maintaining the data needed, and completing and reviewing each collection of information. Title : Establishment and Maintenance of Records Description

The Department of Defense (DoD) requires defense contractors to protect sensitive unclassified information in accordance with requirements for FCI and CUI. To verify contractor and subcontractor implementation of DoD's cybersecurity information protection requirements, the Department developed the Cybersecurity Maturity Model Certification (CMMC) Program as a means of assessing and verifying adequate protection of contractor information systems that process, store, or transmit either FCI or CUI. The CMMC Program is intended to: (1) align cybersecurity requirements to the sensitivity of unclassified information to be protected, (2) add a self-assessment element to affirm implementation of applicable cybersecurity requirements, (3) add a certification element to verify implementation of cybersecurity requirements, and (4) add an affirmation to attest to continued compliance with assessed requirements. As part of the program, DoD also intends to provide supporting resources and training to the DIB, to help support companies who are working to achieve the required CMMC level. The CMMC Program provides for assessment at three levels, starting with basic safeguarding of FCI at CMMC Level 1, moving to the broad protection of CUI at CMMC Level 2, and culminating with higher-level protection of CUI against risk from Advanced Persistent Threats (APTs) at CMMC Level 3. The CMMC Program addresses DoD's need to protect its sensitive unclassified information during the acquisition and sustainment of products and services from the DIB. This effort is instrumental in establishing cybersecurity as a foundation for DoD acquisitions. Although DoD contract requirements to provide adequate security for covered defense information (reflected in DFARS clause 252.204-7012) predate CMMC by many years, a certification requirement for the handling of CUI to (printed page 89078) assess a contractor or subcontractor's implementation of those required information security controls is new with the CMMC Program. The theft of intellectual property and sensitive information from all U.S. industrial sectors from malicious cyber activity threatens economic security and national security. The Council of Economic Advisers estimates that malicious cyber activity cost the U.S. economy between \$57 billion and \$109 billion in 2016. [19] The Center for Strategic and International Studies estimates that the total global cost of cybercrime was as high as \$600 billion in 2017. [20] Malicious cyber actors have targeted and continue to target defense contractors and the DoD supply chain. These attacks not only focus on the large prime contractors, but also target subcontractors that make up the lower tiers of the DoD supply chain. Many of these subcontractors are small entities that provide critical support and innovation. Overall, the DIB sector consists of over 220,000 companies [21]

the privacy and security certification framework for Health IT Modules. Section 170.550(h) identifies a mandatory minimum set of the certification criteria that ONC ACBs must ensure are also included as part of specific Health IT Modules that are presented for certification. For example, to meet the '[s]tandardized API for patient and population services' certification criterion, the ONC Health IT Certification Program requires that a Health IT Module presented for testing and certification must demonstrate the ability to establish a secure and trusted connection with an application requesting data for patients. See 45 CFR 170.315(g)(10) ; see also 45 CFR 170.215 . Back to Citation 738. · See ·Resource for Health Care Providers on Educating Patients about Privacy and Security Risks to Protected Health Information when Using Remote Communication Technologies for Telehealth,· Office of Civil Rights, U.S. Department of Health and Human Services, (Oct. 17, 2023), <https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/resource-health-care-providers-educating-patients/index.html> . Back to Citation 739. · See 45 CFR part 171 ; 85 FR 25642 , 25815 (May 1, 2020). Back to Citation 740. See, e.g., 45 CFR part 171 . Back to Citation 741. 45 CFR 164.308(a)(13) . Back to Citation 742. · See ·Next Steps Toward Managing Legacy Medical Device Cybersecurity Risks,· MITRE Corporation (Nov. 2023), <https://www.mitre.org/sites/default/files/2023-11/PR-23-3695-Managing-Legacy-Medical-Device%20Cybersecurity-Risks.pdf> ; ·Principles and Practices for the Cybersecurity of Legacy Medical Devices,· International Medical Device Regulators Forum, p. 8 (Apr. 11, 2023), https://www.imdrf.org/sites/default/files/2023-04/IMDRF%20Principles%20and%20Practices%20of%20Cybersecurity%20for%20%20Legacy%20Medical%20Devices%20Final%20%28N70%29_1.pdf. Back to Citation 743. ·Cybersecurity,· U.S. Food & Drug Administration, U.S. Department of Health and Human Services, <https://www.fda.gov/medical-devices/digital-health-center->

excellence/cybersecurity . Back to Citation 744. . See sec. 3305 of Public Law 117-328 , 126 Stat. 5832 (Dec. 29, 2022) (codified at 21 U.S.C. 360n-2); see also Cybersecurity in Medical Devices Frequently Asked Questions (FAQs), U.S. Food & Drug Administration, U.S. Department of Health and Human Services, <https://www.fda.gov/medical-devices/digital-health-center-excellence/cybersecurity-medical-devices-frequently-asked-questions-faqs> . Back to Citation 745. Celia Paulsen, et al., Glossary of Key Information Security Terms, NIST Interagency and Internal Reports 7298, Revision 3, National Institute of Standards and Technology, U.S. Department of Commerce (July 3, 2019), <https://nvlpubs.nist.gov/nistpubs/ir/2019/NIST.IR.7298r3.pdf> . Back to Citation

Contractors will appoint security officials who are U.S. citizens, unless the provisions of § 117.11(e)(1)(iii) apply for the SMO and ITPSO. * * * * (h) * * * (1) * * * (i) Review cycle. The CSA will determine the scope and frequency of security reviews, which may be increased or decreased consistent with risk management principles. Security reviews may be conducted not more often than once every 12 months unless special circumstances exist, to include addressing security vulnerabilities found during a previous security review. (ii) * * * (A) The CSA will generally provide notice to the contractor of a forthcoming review, but may also conduct unannounced reviews at its discretion, e.g., if there is possible imminent loss or compromise of classified information. The CSA security review may subject contractor employees and all areas and receptacles under the control of the contractor to examination. * * * * 5. Amend § 117.8 by revising paragraphs (a)(2)(ii), (c)(7)(iii)(B), and (c)(14) to read as follows: § 117.8 Reporting requirements. (a) * * * (2) * * * (ii) Provide requested information to enable the CSA to ascertain whether classified information is adequately protected in accordance with this rule. * * * * (c) * * * (7) * * * (iii) * * * (B) Whether they have been excluded from access to classified information in accordance with § 117.7(c)(2). * * * * (14) Reporting by subcontractor. Subcontractors will also notify their prime contractors if they make any reports to their CSA that affect the status of the entity eligibility determination (e.g., FCL), may indicate an employee poses as an insider threat, affect the proper safeguarding of classified information, or indicate classified information has been lost or compromised. * * * * 6. Amend § 117.9 by: a. Revising paragraph (f); and b. Redesignating paragraphs (h)(i) and (h)(ii) as paragraphs (h)(1) and (h)(2). The revision reads as follows: § 117.9 Entity eligibility determination for access to classified information. * * * * (f) Exclusion procedures. If a CSA determines that certain KMP can be excluded from access to classified information, the contractor will follow the procedures in accordance with § 117.7(c)(2). * * * * 7. Amend § 117.11 by: a. In paragraph (d)(2)(iii)(B)(4), removing the words SCI, RD, or COMSEC and adding in their place the words proscribed information; and b. Revising paragraph (h)(4). The revision reads as follows: § 117.11 Foreign Ownership, Control, or Influence (FOCI). * * * * (h) * * * (4) Facilities location plan.

The Department proposes a new implementation specification for criticality analysis at proposed 45 CFR 164.308(a)(13)(ii)(A) . This would require a regulated entity to perform and document an assessment of the relative criticality of its relevant electronic information systems and technology assets in its relevant electronic information systems. The proposal would not limit this analysis to electronic information systems that create, receive, maintain, or transmit ePHI because other electronic information systems and/or technology assets may be crucial to ensuring the confidentiality, integrity, or availability of ePHI, providing patient care, and supporting other business needs. A prioritized list of specific relevant electronic information systems and technology assets in those electronic information systems would help a regulated entity to determine their criticality and the order of restoration. [610] Under this proposal, the implementation specification for establishing and implementing a data backup plan would be redesignated as proposed 45 CFR 164.308(a)(13)(ii)(B) and renamed Data backups. It would also be modified to clarify that the procedures to create and maintain exact retrievable copies of ePHI must be in writing, and to also require such procedures to include verifying that the ePHI has been copied accurately. For example, the ability to access ePHI from a remote location in the event of a total failure should be reflected in the procedures specified for data backups. The proposed implementation specification for backing up information systems at proposed paragraph (a)(13)(ii)(C) would require a regulated entity to establish and implement written procedures to create and maintain backups of its relevant electronic information systems, including verifying the success of such backups. Establishing such procedures would ensure that the ePHI in relevant electronic information systems is both protected and available. Additionally, the Department proposes to redesignate the implementation

specification for disaster recovering planning as paragraph (a)(13)(ii)(D). We propose to clarify that a regulated entity would be required to establish (and implement as needed) written procedures to restore both its critical relevant electronic information systems and data within 72 hours of the loss, and to restore the loss of other relevant electronic information systems and data in accordance with its criticality analysis. [611] The Department proposes to clarify the implementation specification for emergency mode operation planning, redesignated as proposed 45 CFR 164.308(a)(13)(ii)(E)

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.11.08E Dynamic Threat Awareness Determine the current cyber threat environment on an ongoing basis using [Assignment: organization-defined means]. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 DISCUSSION 1546

E. Comments on What Definitions Apply to this Subpart? (Proposed § 1.328) F. Comments on Do Other Statutory Provisions and Regulations Apply? (Proposed § 1.329) G. Comments on Can Existing Records Satisfy the Requirements of this Subpart? (Proposed § 1.330) H. Comments on What Information is Required in the Records You Must Establish and Maintain to Identify the Nontransporter and Transporter Immediate Previous Source and Immediate Subsequent Recipients? (Proposed §§ 1.337 and 1.345) I. Comments on Who is Required to Establish and Maintain Records for Tracing the Transportation of All Food? (Proposed § 1.351) J. Comments on What Information is Required in the Transportation Records? (Proposed § 1.352) K. Comments on What Are the Record Retention Requirements? (Proposed § 1.360) L. Comments on What Are the Record Availability Requirements? (Proposed § 1.361) M. Comments on What Records Are Excluded From this Subpart? (Proposed § 1.362) N. Comments on What Are the Consequences of Failing to Establish and Maintain Records or Make Them Available to FDA as Required By This Subpart? (Proposed § 1.363) O. Comments on What Are the Compliance Dates for This Subpart? (Proposed § 1.368) IV. Analysis of Economic Impacts·Final Regulatory Impact Analysis A. Summary of the Costs and Benefits of the Final Rule B. Description of Proposed Rule C. General Comments D. The Tradeoff Between Costs and Risk Reduction E. Estimating the Benefits F. Costs G. Summary of the Costs and Benefits of the Final Rule and Policy V. Final Regulatory Flexibility Analysis VI. Unfunded Mandates VII. SBREFA VIII. Paperwork Reduction Act of 1995 IX. Analysis of Environmental Impact X. Federalism XI. References I. Background and Legal Authority The events of September 11, 2001, have highlighted the need to enhance the security of the infrastructure of the United States, including the food supply. Congress responded by enacting the Bioterrorism Act (Public Law 107-188), which was signed into law on June 12, 2002. The Bioterrorism Act includes a provision in title III (Protecting Safety and Security of Food and Drug Supply), subtitle A·Protection of Food Supply, section 306, which amends the Federal Food, Drug, and Cosmetic Act (the FD&C Act) by adding section 414, Maintenance and Inspection of Records (21 U.S.C. 350c). (In the regulation itself, which is codified in title 21 of the Code of Federal Regulations

(i) The individuals shall be advised of what specific data was involved. It is insufficient to simply state that personal information has been lost. Where names, social security numbers, and dates of birth are involved, it is critical that the individual be advised that these data elements potentially have been compromised. (ii) The individual shall be informed of the facts and circumstances surrounding the loss, theft, or compromise. The description of the loss should be sufficiently detailed so that the individual clearly understands how the compromise occurred. (iii) The individual shall be informed of what protective actions the Component is taking or the individual can take to mitigate against potential future harm. The Component should refer the individual to the Federal Trade Commission's public Web site on identity theft at http://www.consumer.gov/idtheft/con_steps.htm . The site provides valuable information as to what steps individuals can take to protect themselves if their identities potentially have been or are stolen. (iv) A sample notification letter is at Appendix B. (b) The notification shall be made whether or not the personal information is contained in a system of records (See § 310.10(a)). Subpart C·Collecting Personal Information § 310.15 General considerations. (a) Collect directly from the individual. Collect to the greatest extent practicable personal information directly from the individual to whom it pertains if the information may result in adverse determination about an individual's rights, privileges, or benefits under any Federal program. (b) Collecting social security numbers (SSNs). (1) It is unlawful for any Federal, State, or local governmental agency to deny an individual any right, benefit, or privilege provided by law because the individual refuses to provide his or her SSN. However, if a Federal statute requires the SSN be furnished or if the SSN

is furnished to a DoD Component maintaining a system of records in existence that was established and in operation before January 1, 1975, and the SSN was required under a statute or regulation adopted prior to this date for purposes of verifying the identity of an individual, this restriction does not apply. (2) When an individual is requested to provide his or her SSN, he or she must be told: (i) What uses will be made of the SSN; (ii) The statute, regulation, or rule authorizing the solicitation of the SSN; and (iii) Whether providing the SSN is voluntary or mandatory. (3) Include in any systems notice for any system of records that contains SSNs a statement indicating the authority for maintaining the SSN. (4) E.O. 9397, "Numbering System for Federal Accounts Relating to Individual Persons", November 30, 1943, authorizes solicitation and use of SSNs as a numerical identifier for Federal personnel that are identified in most Federal record systems. However, it does not constitute authority for mandatory disclosure of the SSN.

Additionally, as discussed above, the Department proposes to remove the distinction between required and addressable implementation specifications and make all implementation specifications required, with specific, limited exceptions. Also as discussed above, we propose to modify certain standards and implementation specifications to clarify that the technical safeguards apply to ensure the confidentiality, integrity, and availability of ePHI, which requires a regulated entity to implement the technical safeguards in or on all relevant electronic information systems. These proposals are discussed in greater detail below.

b. Section 164.312(a)(1) Standard: Access Control The Department proposes to clarify the standard for access control at 45 CFR 164.312(a)(1) by requiring a regulated entity to deploy technical controls in relevant electronic information systems to allow access only to those users and technology assets that have been granted access rights. This proposed modification would ensure that a regulated entity deploys technical controls, rather than solely ensuring that it implements technical policies and procedures, consistent with our proposals to define "deploy" and "implement." [695] Thus, the proposal would clarify that a regulated entity is not expected to merely establish a policy and procedure, but must also put into place, ensure the operation of, and verify the continued operation of, technical controls for access to its relevant electronic information systems such that the failure to have such technical control in operation throughout its enterprise would be a violation of the new proposed standard. Additionally, the Department's proposal would clarify that access controls would apply to persons with authorized access and to technology assets. Access controls are one of the key mechanisms by which a regulated entity protects ePHI. Such technical controls ensure that access to the regulated entity's electronic information systems is limited to only users and technology assets that have been granted access rights under the policies and procedures adopted in accordance with the standard for information access management under 45 CFR 164.308. [696] The Security Rule does not identify a specific type of access control method or technology to deploy, nor are we proposing to do so in this rule. [697] As discussed above, access rights should be role-based and the technical controls should assist the regulated entity in implementing such policies and procedures. For example, workforce members responsible for monitoring and administering a regulated entity's relevant electronic information systems, such as someone responsible for cybersecurity or providing technical support to users, must only have access to ePHI and to the regulated entity's relevant electronic information systems as appropriate for their role and job function. We also propose at 45 CFR 164.312(a)(1) to add a paragraph heading to clarify the organization of the regulatory text.

(2) An adequate description of the type of food released, to include brand name and specific variety (e.g., brand x cheddar cheese, not just cheese; or romaine lettuce, not just lettuce); (3) The date you released the food; (4) For persons who manufacture, process, or pack food, the lot or code number or other identifier of the food (to the extent this information exists); (5) The quantity and how the food is packaged (e.g., 6 count bunches, 25 lb carton, 12 oz bottle, 100 gal tank); (6) The name of the firm, address, telephone number, and, if available, the fax number and e-mail address of the transporter immediate subsequent recipient (the transporter who transported the food from you); and (b) Your records must include information reasonably available to you to identify the specific source of each ingredient used to make every lot of finished product. Requirements for Transporters to Establish and Maintain Records §1.352 What information must transporters establish and maintain? If you are a transporter, you must establish and maintain the following (printed page 71654) records for each food you transport in the United States. You may fulfill this requirement by either: (a) Establishing and maintaining the following records: (1) Names of the transporter's immediate previous source and transporter's immediate subsequent recipient; (2) Origin and destination points; (3) Date shipment received and date released; (4) Number of packages; (5) Description of freight; (6) Route of movement during the time you transported the

food; and (7) Transfer point(s) through which shipment moved; or (b) Establishing and maintaining records containing the following information currently required by the Department of Transportation's Federal Motor Carrier Safety Administration (of roadway interstate transporters (49 CFR 373.101 and 373.103) as of December 9, 2004: (1) Names of consignor and consignee; (2) Origin and destination points; (3) Date of shipment; (4) Number of packages; (5) Description of freight; (6) Route of movement and name of each carrier participating in the transportation; and (7) Transfer points through which shipment moved; or (c) Establishing and maintaining records containing the following information currently required by the Department of Transportation's Surface Transportation Board of rail and water interstate transporters (49 CFR 1035.1 and 1035.2) as of December 9, 2004: (1) Date received; (2) Received from; (3) Consigned to; (4) Destination; (5) State of; (6) County of; (7) Route; (8) Delivering carrier; (9) Car initial; (10) Car no; (11) Trailer initials/number; (12) Container initials/number; (13) No. packages; and (14) Description of articles; or (d) Establishing and maintaining records containing the following information currently required by the Warsaw Convention of international air transporters on air waybills: (1) Shipper's name and address; (2) Consignee's name and address; (3) Customs reference/status; (4) Airport of departure and destination; (5) First carrier; and

The Department considered proposing an exception to the MFA authentication requirement that would permit regulated entities in the future to adopt other technologies, in lieu of MFA, that might offer a more secure method of authenticating user identity. [997] Based on discussions with cybersecurity experts, the Department believes that MFA is likely to remain the most secure method for authenticating user identity in future years. It may take different forms, but it will still, at its core, meet the definition of MFA proposed in this NPRM for the foreseeable future. [998] While the Department acknowledges that technology will continue to evolve, we are unable to predict when and whether future technology will address identity verification and exceed the level of protection offered by MFA. This uncertainty renders us unable to articulate requirements specific enough to justify a purposeful exception. Because of the uncertainty surrounding new technologies, we are also unable to estimate costs of adopting this alternative. Our current view is that proposing and codifying such an exception would be premature, but we will revisit the proposed specific requirement for MFA, if adopted, and reconsider the need for an exception should a more secure technology emerge.

Transition for Business Associates and Group Health Plans The Department considered requiring regulated entities to comply with all of the proposals in this NPRM by the compliance date, rather than proposing transition provisions for existing business associate agreements or other contractual arrangements. Had the Department taken that approach, we would have proposed that regulated entities update all existing business associate agreements by the proposed compliance date to comply with all applicable proposed requirements in this NPRM. While the Department believes that many of the proposals in this NPRM are consistent with the Security Rule as it currently exists, we are also concerned that too many regulated entities are not currently compliant with the Security Rule. Given the demonstrable increase in breaches, we believe that it is more important for regulated entities to first improve their cybersecurity posture by coming into compliance with all applicable proposed requirements in this NPRM, if adopted. Upon doing so, the Department anticipates that regulated entities will be better positioned to evaluate their contractual needs and to modify existing business associate agreements. For this reason, the Department has proposed the transition provisions in proposed 45 CFR 164.318

(A) From subsections (c)(3) and (d) when access to accounting disclosure and access to or amendment of records would cause the identity of a confidential source to be revealed. Disclosure of the source's identity not only will result in the Department breaching the promise of confidentiality made to the source but it will impair the Department's future ability to compile investigatory material for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, Federal contracts, or access to classified information. Unless sources can be assured that a promise of confidentiality will be honored, they will be less likely to provide information considered essential to the Department in making the required determinations. (B) From subsection (e)(1) because in the collection of information for investigatory purposes, it is not always possible to determine the relevance and necessity of particular information in the early stages of the investigation. It is only after the information is evaluated in light of other information that its relevance and necessity becomes clear. Such information permits more informed decision-making by the Department when making required suitability, eligibility, and qualification determinations. (19) System identifier and name. DA&M 01, Civil Liberties Program Case Management System. (i) Exemption. Records contained in this System of Records may be exempted from the

requirements of subsections (c)(3); (d)(1), (2), (3), and (4); (e)(1) and (e)(4)(G), (H), and (I); and (f) of the Privacy Act pursuant to 5 U.S.C. 552a(k)(1). Records may be exempted from these subsections or, additionally, from the requirements of subsections (c)(4); (e)(2), (3), and (8) of the Privacy Act of 1974 consistent with any exemptions claimed under 5 U.S.C. 552a (j)(2) or (k)(1), (k)(2), or (k)(5) by the originator of the record, provided the reason for the exemption remains valid and necessary. An exemption rule for this system has been promulgated in accordance with the requirements of 5 U.S.C. 553(b)(1), (2), and (3), (c) and (e) and is published at 32 CFR part 311. (ii) Authority. 5 U.S.C. 552a (j)(2), (k)(1), (k)(2), or (k)(5). (iii) Reasons. (A) From subsections (c)(3) (accounting of disclosures) because an accounting of disclosures from records concerning the record subject would specifically reveal an intelligence or investigative interest on the part of the Department of Defense and could result in release of properly classified national security or foreign policy information.

Controlled Unclassified Information (CUI) is information the Government creates or possesses, or that an entity creates or possesses for or on behalf of the Government, that a law, regulation, or Government-wide policy requires or permits an agency to handle using safeguarding or dissemination controls. CUI is not classified information but requires protection beyond what is provided to general public information. CUI is governed by 32 CFR Part 2002 and the ISOO CUI Registry, which lists 125 categories across 20 index groupings. In the defense context, CUI is the primary category of information that CMMC is designed to protect. Examples of CUI in the DIB include: technical data, export-controlled information, proprietary business information provided by the government, vulnerability assessments, and personally identifiable information (PII) in government contracts.

d. Whether there should be exceptions to any of the proposed or existing technical safeguards or related implementation specifications, in addition to those proposed for encryption and decryption and MFA. For example, are there any proposed or existing standards or implementation specifications with which small or rural regulated entities would have substantial difficulty complying? If so, please explain the type of regulated entities that would be adversely affected by the requirement, the nature of the compliance difficulty, and any alternative or compensating measures that such entities are implementing now or could implement in the event of such requirement to address the risk to ePHI posed by the specific standard or implementation specification. e. Whether the exceptions the Department has proposed to the standard for encryption or decryption are appropriate. If not, please explain. f. Data about the frequency and number of requests regulated entities receive pursuant to the individual right of access at 45 CFR 164.524 where an individual requests that the regulated entity transmit to the individual or a third party a copy of the individual's ePHI via unencrypted email or other unencrypted messaging technologies. Please confirm that these are requests made pursuant to the individual right of access, rather than other types of communications, such as appointment reminders or requests made pursuant to a valid authorization. g. Whether the Department should provide any additional exceptions to standard for encryption or decryption. If so, please explain. h. Whether there are additional criteria or parameters for encryption that regulated entities would find helpful. If yes, please explain and provide examples. i. Whether the Department should require review of compensating controls implemented to comply with an exception to the encryption and decryption standard more frequently than once every 12 months where there are no environmental or operational changes. j. With respect to the exception to the standard for encryption and decryption for certain requests made pursuant to the individual right of access, whether there are forms and formats the Department should include or exclude from the exception (e.g., portable document format (PDF)). If so, please explain. k. Resources that regulated entities have identified to help inform individuals about the risks associated with the unencrypted transmission of ePHI, and whether the Department should compile and publish a list of such resources. l. Whether the Department should define in regulation or guidance what constitutes a prevailing cryptographic standard. If so, please explain. m. Whether the Department should specify the deployment of a particular form or manner of encryption, such as the use of particular algorithms, protocols, or compliance standards. If so, please explain.

(3) Board members, who have denial authority, may not vote on a matter upon which they took Denial Authority action. However, an individual who took Denial Authority action, or his or her representative, may serve as a non-voting member when the Board considers matters in the Denial Authority's area of functional specialization. (4) The Board may seek additional information, including the requester's official personnel file, if relevant and necessary to decide the appeal. (5) If the Board determines that an amendment is warranted (the record is inaccurate as a matter of

fact rather than judgment, irrelevant, untimely, or incomplete) it will amend the record and notify the requester, the Denial Authority, the custodian of the record, and any prior recipients of the record, of the amendment. (6) If the Board determines that amendment is unwarranted, they will:

- (i) Obtain the General Counsel's concurrence in writing;
- (ii) Respond to the requester with the reasons for denial; and
- (iii) Inform the requester of the right to file a Statement of Disagreement with the Board's action and to seek judicial review of the Army's refusal to amend. A Statement of Disagreement must be received by the system manager within 120 days and it will be made an integral part of the pertinent record. Anyone who may have access to, use of, or need to disclose information from the record will be aware that the record was disputed. The disclosing authority may include a brief summary of the Board's reasons for not amending the disputed record.

(7) It is inappropriate for the Privacy Act Review Board to consider any record which is exempt from the amendment provision of the Privacy Act. § 505.7 Disclosure of personal information to other agencies and third parties. (a) Disclosing records to third parties. (1) DA is prohibited from disclosing a record from a Privacy Act system of records to any person or agency without the prior written consent of the subject of the record, except when:

- (i) Pursuant to the twelve Privacy Act exceptions. The twelve exceptions to the 'no disclosure without consent' rule are those exceptions which permit the release of personal information without the individual's/subject's consent (See appendix C of this part).
- (ii) The FOIA requires the release of the record. One of the twelve exceptions to Privacy Act is the FOIA Exception. If the FOIA requires the release of information, the information must be released. The Privacy Act can not prevent release to a third party if the FOIA requires release. However, information must not be discretionarily released under the FOIA if the information is subject to the Privacy Act's 'no disclosure without consent' rule.

(1) The release of home addresses and home telephone numbers normally is prohibited. This release is normally considered a clearly 'unwarranted invasion' of personal privacy and is exempt from mandatory release under the FOIA. However, home addresses and home telephone numbers may still be released if:

- (i) The individual has indicated previously in writing that he or she has no objection to the release;
- (ii) The source of the information to be released is a public document such as commercial telephone directory or other public listing;
- (iii) The release is required by Federal statute (for example, pursuant to federally funded state programs to locate parents who have defaulted on child support payments) (See 42 U.S.C. 653); or
- (iv) The releasing of information is pursuant to the routine use exception or the 'intra-agency need to know' exception to the Privacy Act.

(2) A request for a home address or telephone number may be referred to the last known address of the individual for a direct reply by the individual to the requester. In such cases, the requester shall be notified of the referral. (3) Do not sell or rent lists of individual names and addresses unless such action is specifically authorized by the appropriate authority. (f) Emergency Recall Rosters. (1) The release of emergency recall rosters normally is prohibited. Their release is normally considered a clearly 'unwarranted invasion' of personal privacy and is exempt from mandatory release under the FOIA. Emergency recall rosters should only be shared with those who have an 'official need to know' the information, and they should be marked 'For Official Use Only' (See AR 25-55). (2) Do not include a person's SSN on an emergency recall roster or their spouse's name. (3) Commanders and supervisors should give consideration to those individuals with unlisted phone numbers. Commanders and supervisors should consider limiting access to an unlisted number within the unit. (g) Social Rosters. (1) Before including personal information such as a spouse's name, home addresses, home phone numbers, and similar information on social rosters or social directories, which will be shared with individuals, always ask for the individual's written consent. Without their written consent, do not include this information. (2) Collection of this information will require a Privacy Act Statement which clearly tells the individual what information is being solicited, the purpose, to whom the disclosure of the information is made, and whether collection of the information is voluntary or mandatory. (h) Disclosure of personal information on group orders. (1) Personal information will not be posted on group orders so that everyone on the orders can view it. Such a disclosure of personal information violates the Privacy Act and this part. (2) The following are some examples of personal information that should not be contained in group orders. The following list is not all inclusive:

- (i) Complete SSN;

means the senior level representative from within each Organization Seeking Assessment (OSA) who is responsible for ensuring the OSA's compliance with the CMMC Program requirements and has the authority to affirm the OSA's continuing compliance with the specified security requirements for their respective organizations. (CMMC-custom term) Assessment means the testing or evaluation of security controls to determine the extent to which the controls are implemented correctly, operating

as intended, and producing the desired outcome with respect to meeting the security requirements for an information system or organization, as defined in §§ 170.15 through 170.18. (CMMC-custom term)

(i) Level 1 self-assessment is the term for the activity performed by an OSA to evaluate its own information system when seeking a CMMC Status of Level 1 (Self). (ii) Level 2 self-assessment is the term for the activity performed by an OSA to evaluate its own information system when seeking a CMMC Status of Level 2 (Self). (iii) Level 2 certification assessment is the term for the activity performed by a C3PAO to evaluate the information system of an OSC when seeking a CMMC Status of Level 2 (C3PAO). (iv) Level 3 certification assessment is the term for the activity performed by the DCMA DIBCAC to evaluate the information system of an OSC when seeking a CMMC Status of Level 3 (DIBCAC). (v) POA&M closeout self-assessment is the term for the activity performed by an OSA to evaluate only the NOT MET requirements that were identified with POA&M during the initial assessment, when seeking a CMMC Status of Final Level 2 (Self). (vi) POA&M closeout certification assessment is the term for the activity performed by a C3PAO or DCMA DIBCAC to evaluate only the NOT MET requirements that were identified with POA&M during the initial assessment, when seeking a CMMC Status of Final Level 2 (C3PAO) or Final Level 3 (DIBCAC) respectively. Assessment Findings Report means the final written assessment results by the third-party or government assessment team. The Assessment Findings Report is submitted to the OSC and to the DoD via CMMC eMASS. (CMMC-custom term) Assessment objective means a set of determination statements that, taken together, expresses the desired outcome for the assessment of a security requirement. Successful implementation of the corresponding CMMC security requirement requires meeting all applicable assessment objectives defined in NIST SP 800-171A Jun2018 (incorporated by reference, see § 170.2) or NIST SP 800-172A Mar2022 (incorporated by reference, see § 170.2). (CMMC-custom term) Assessment Team means participants in the Level 2 certification assessment (CMMC Certified Assessors and CMMC Certified Professionals) or the Level 3 certification assessment (DCMA DIBCAC assessors). This does not include the OSC participants preparing for or participating in the assessment. (CMMC-custom term) Asset means an item of value to stakeholders. An asset may be tangible (e.g.,

There is no CMMC 2.0 Level 4. CMMC 2.0 defines three levels: - Level 1: 15 FAR 52.204-21 basic safeguarding requirements - Level 2: 110 NIST SP 800-171 security requirements - Level 3: NIST SP 800-172 enhanced security requirements The original CMMC 1.0 had five levels (1-5), but CMMC 2.0 consolidated these into three. If you need the highest level of protection under CMMC, that is Level 3.

<https://eportal.nspa.nato.int/Codification/CageTool/home> . As specified in §§ 170.15 and 170.16, SPRS inputs include the industry CAGE codes(s) associated with the information system(s) addressed by the CMMC Assessment Scope. For each new information system used to support a DoD contract with FCI or CUI, a new SPRS entry is required. If the contractor or subcontractor will use an information system associated with a CAGE code already recorded in SPRS then a new entry is not required. 3. Assessors and Certificates Comment: One commenter asked if an assessor is prohibited from interacting with OSA IT tools such as MS Office 365 or cloud based GRC tools. One commenter requested the CMMC rule require C3PAOs to clearly indicate the CMMC Assessment Scope on the CMMC Certificate of CMMC Status, to include CAGE codes, that could be shared with trusted partners. Response: The rule text in § 170.11(b)(7) does not prohibit collecting assessment evidence within the OSC environment using the OSC's IT. This section applies only to IT used (printed page 83135) by the assessors to process, store, or transmit assessment-related information once it leaves the OSC environment. The rule has been modified to list the minimum required information to be included on the Certificate of CMMC Status, including CAGE code. h. Reassessment Comment: Some commenters interpreted the end of a CMMC assessment validity period (and need for new assessment) as having the same significance or meaning as a 'reassessment', which the rule describes as potentially necessary only in rare circumstances when cybersecurity risks, threats, or awareness have changed. Another commenter asked for examples of circumstances that might prompt a re-assessment and description of the process for completing one. Four commenters expressed concern that re-assessments might be frequent, costly, and time-consuming. These commenters sought confirmation that relatively common system maintenance activities would not require a new assessment or prevent annual affirmation. One commenter questioned the rationale for differences between validity periods for CMMC Level 1 versus Levels 2 and 3 assessment and recommended standardization on either a 1-year or 3-year frequency for all levels. Other commenters asserted that annual affirmations would drive a need for annual assessments at levels 2 or 3 and requested deletion of the affirmation requirement. One commenter asked whether system changes within an assessment scope would require notification to the contracting agency. Another asked for guidance on remediation of POA&M items and asked whether

systems that fall out of compliance must be identified to the contracting agency. Response:

Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7), but only to the extent that the disclosure of such material would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(7) from the following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(4)(G), (H), and (I); and (f). (ii) Authority. 5 U.S.C. 552a(k)(7). (iii) Reasons. To protect the integrity of information used in the Reserve Initial Brigadier General Screening Board, the release of which would compromise the selection process. (8) System identification and name. F036 AF PC O, General Officer Personnel Data System. (i) Exemption. Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7), but only to the extent that the disclosure of such material would reveal the identity of a confidential source. Therefore, portions of this system of records (Air Force General Officer Promotion and Effectiveness Reports with close out dates on or before January 31, 1991) may be exempt pursuant to 5 U.S.C. 552a(k)(7) may be exempt from following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(4)(H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(7). (iii) Reasons. (A) From subsection (c)(3) because making the disclosure accounting available to the individual may compromise express promises of confidentiality by revealing details about the report and identify other record sources, which may result in circumvention of the access exemption. (B) From subsection (d) because individual disclosure compromises express promises of confidentiality conferred to protect the integrity of the promotion rating system. (C) From subsection (e)(4)(H) because of and to the extent that portions of this record system are exempt from the individual access provisions of subsection (d). (D) From subsection (f) because of and to the extent that portions of this record system are exempt from the individual access provisions of subsection (d). (9) System identifier and name. F036 AFPC K, Historical Airman Promotion Master Test File. (i) Exemption. Testing or examination material used solely to determine individual qualifications for appointment or promotion in the federal or military service, if the disclosure would compromise the objectivity or fairness of the test or examination process may be exempt pursuant to 5 U.S.C. 552a(k)(6), if the disclosure would compromise the objectivity or fairness of the test or examination process. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(6) from the following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(6). (iii) Reasons. To protect the integrity, objectivity, and equity of the promotion testing system by keeping test questions and answers in confidence. (iv) [Reserved] (10) System identifier and name.

All cleared employees must submit foreign travel reports and receive any pre-travel briefings or post travel briefings from the FSO-based on threat according to this rule, SEAD 3 and CSA-provided guidance for unique mission requirements. It is estimated that the number of foreign travel reports submitted annually will be 483,681 to comply with this rule. That estimate is based on analysis of calendar year 2019 unofficial foreign travel reported by DoD civilians and military in the DoD Aircraft and Personnel Automated Clearance System (APACS), a web-based tool for the creation, submission and approval of aircraft diplomatic clearances and personnel travel clearances (i.e. Country, Theater and Special Area, as applicable with individual DoD Foreign Clearance Guide (FCG), <https://www.fcg.pentagon.mil> country pages) designed to aid USG travelers on official government and unofficial (i.e., leave) travel. For calendar year 2019, there were 126,131 travelers and 113,214 travel requests submitted into APACS. APACS requirements are published on the DoD Foreign Clearance Guide (FCG), <https://www.fcg.pentagon.mil>. Thus an annual estimate of .89 expected foreign travel trips by traveler (113,214 divided by 126,131). In the small business analysis, there were a total of 18,242 cleared employees in the 658 small entities sampled and 63,598 cleared employees in the remaining 356 non-small businesses. Of the total cleared employees in the small business analysis (as reported in the National Industrial Security System), approximately 22.3% were at small entities and 77.7% were at non-small businesses. Known number of new travelers expected to be effected by this rule is 543,462 SECRET cleared contractor personnel under DoD security cognizance and the estimated trips at .89 per traveler is $(543,462 \times .89 = 483,681 \text{ estimated trips})$. Assuming the ratio for those employees reporting foreign travel into APACS is the same as SECRET cleared employees would report, of the estimated 483,681 foreign trips by SECRET cleared employees, it can be estimated that approximately 107,812 (22.3% of 483,681) will be taken by contractors at small entities, and 375,869 (77.7% of 483,681) by contractors at non-small businesses. It is estimated that it will take a half an hour for a SECRET cleared employee to report foreign travel in 2021 and in each of the following years up to year 20 to report foreign travel and receive any pre-

travel or post-travel briefings. The estimated average labor rate for a SECRET cleared employee to report foreign travel is the equivalent of a GS11 step 5. These assumptions imply costs of \$16.81 million in each year one through 20. e. Fewer contract performance delays by the small number of U.S. contractors with NTIB ownership operating under an SSA. Section 842 of Public Law 115-232

Back to Citation 550. See *id.* at 36. Back to Citation 551. · See proposed 45 CFR 164.308(a)(9)(i) . Back to Citation 552. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· *supra* note 461, p. 36. Back to Citation 553. See *id.* Back to Citation 554. · See ·Security Standards: Administrative Safeguards,· *supra* note 517, p. 10. Back to Citation 555. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· *supra* note 461, p. 37. Back to Citation 556. · See ·Insider Threats and Termination Procedures,· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Nov. 2017), <https://www.hhs.gov/sites/default/files/november-cybersecurity-newsletter-11292017.pdf> . Back to Citation 557. · See ·Managing Malicious Insider Threats,· *supra* note 528. Back to Citation 558. *Id.* Back to Citation 559. · See 45 CFR 164.308(a)(4)(ii)(C) . Back to Citation 560. · See ·Security Standards: Administrative Safeguards,· *supra* note 517, p. 10-11. Back to Citation 561. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· *supra* note 461. Back to Citation 562. · See proposed 45 CFR 164.308(a)(9)(ii)(A) . Back to Citation 563. See proposed 45 CFR 164.308(a)(9)(ii)(B) . Back to Citation 564. · See proposed 45 CFR 164.308(a)(9)(ii)(E) . Back to Citation 565. ·Cybersecurity Performance Goals,· *supra* note 18. Back to Citation 566. · See ·Security Standards: Administrative Safeguards,· *supra* note 517, p.11. Back to Citation 567. See, e.g., Resolution Agreement, ·Banner Health,· Office for Civil Rights, U.S. Department of Health and Human Services (Dec. 20, 2022), <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/banner-health-racap/index.html> ; ·Montefiore Medical Center,· *supra* note 248. Back to Citation 568. · See 45 CFR 164.502(b) and 164.514(d) . Back to Citation 569. · See Press Release, ·OCR Imposes a \$2.15 Million Civil Money Penalty against Jackson Health System for HIPAA Violation,· U.S. Department of Health and Human Services (Oct. 19, 2019), <https://public3.pagefreezer.com/browse/HHS.gov/31-12-2020T08:51/https://www.hhs.gov/about/news/2019/10/23/ocr-imposes-a-2.15-million-civil-money-penalty-against-jhs-for-hipaa-violations.html> ; see also Notice of Proposed Determination, ·Jackson Health System,· Office for Civil Rights, U.S. Department of Health and Human Services (July 22, 2019), https://public3.pagefreezer.com/browse/HHS.gov/31-12-2020T08:51/https://www.hhs.gov/sites/default/files/jackson-health-system-notice-of-final-determination_508.pdf ; Notice of Final Determination, ·Jackson Health System,· Office for Civil Rights, U.S. Department of Health and Human Services (Oct. 15, 2019),

(5) To find out if an exemption is available for a particular record, refer to the applicable system of records notices. System of records notices will state which exemptions apply to a particular type of record. System of records notices that are applicable to the Army are contained in DA Pam 25-51 (available at the Army Publishing Directorate Web site <http://www.usapa.army.mil/>), the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy/>), or in this section). Some of the system of records notices apply only to the Army and the DOD and some notices are applicable government-wide. (6) Descriptions of current exemptions are listed in detail at appendix C of this part. (b) Exemption procedures. (1) For the General and Specific exemptions to be applicable to the Army, the Secretary of (printed page 46065) the Army must promulgate exemption rules to implement them. This requirement is not applicable to the one Special exemption which is self-executing. Once an exemption is made applicable to the Army through the exemption rules, it will be listed in the applicable system of records notices to give notice of which specific types of records the exemption applies to. When a system manager seeks to have an exemption applied to a certain Privacy Act system of records that is not currently provided for by an existing system of records notice, the following information will be furnished to the DA FOIA/P Office: (i) Applicable system of records notice; (ii) Exemption sought; and (iii) Justification. (2) After appropriate staffing and approval by the Secretary of the Army and the Defense Privacy Office, it will be published in the Federal Register as a proposed rule, followed by a final rule 60 days later. No exemption may be invoked until these steps have been completed. § 505.11 Federal Register publishing requirements. (a) The Federal Register . There are three types of documents relating to the Privacy Act Program that must be published in the Federal Register . They are the DA Privacy

Program policy and procedures (AR 340-21), the DA exemption rules, and Privacy Act system of records notices. (b) Rulemaking procedures. (1) DA Privacy Program procedures and exemption rules are subject to the formal rulemaking process. (2) Privacy Act system of records notices are not subject to formal rulemaking and are published in the Federal Register as Notices, not Rules. (3) The Privacy Program procedures and exemption rules are incorporated into the Code of Federal Regulations (CFR). Privacy Act system of records notices are not published in the CFR. §505.12 Privacy Act enforcement actions. (a) Judicial Sanctions. The Act has both civil remedies and criminal penalties for violations of its provisions. (1) Civil remedies. The DA is subject to civil remedies for violations of the Privacy Act. In addition to specific remedial actions, 5 U.S.C. 552a(g) may provide for the payment of damages, court costs, and attorney's fees. (2) Criminal penalties.

(i) Incorporate appropriate security requirement clauses in a classified contract, IFB, RFP, RFQ, or all solicitations leading to a classified contract. (ii) Provide the contractor with the security classification guidance needed during performance of the contract. (iii) Provide this guidance to the contractor in the contract security classification specification, or equivalent. (2) The contract security classification specification, or equivalent, must identify the specific elements of classified information involved in the contract that require security protection. (3) At the discretion of the CSA, contractors may, to the extent possible, advise and assist in the development and any updates to or any revisions to the contract security classification specification, or equivalent. (4) The contractor will comply with all aspects of the classification guidance. (i) Users of classification guides are encouraged to notify the originator of the guide when they acquire information that suggests the need for change in the instructions contained in the guide. (ii) Classification guidance is the exclusive responsibility of the GCA, and the final determination of the appropriate classification for the information rests with that activity. The contract security classification specification, or equivalent, is a contractual specification necessary for the performance of a classified contract. Challenges to classification status are in paragraph (e) in this section. (iii) If the contractor receives a classified contract without a contract security classification specification, or equivalent, the contractor will notify the GCA. If the GCA does not respond with the appropriate contract security classification specification, or equivalent, the contractor will notify the CSA. (5) Upon completion of a classified contract, the contractor must return all USG provided or deliverable information to the custody of the USG. (i) If the GCA does not advise to the contrary, the contractor may retain (printed page 83337) copies of the USG material for a period of two years following the completion of the contract. The contract security classification specification, or equivalent, will continue in effect for this two-year period. (ii) If the GCA determines the contractor has a continuing need for the copies of the USG material beyond the two-year period, the GCA will issue a final contract security classification specification, or equivalent, for the classified contract and will include disposition instructions for the copies. (e) Challenges to classification status. (1) The contractor will address challenges to classification status with the GCA and request remedy when: (i) Information is classified improperly or unnecessarily. (ii) Current security considerations justify downgrading to a lower classification level or upgrading to a higher classification level. (iii) Security classification guidance is not provided, improper or inadequate.

The definition of ·farm· now states that washing, trimming of outer leaves, and cooling produce are part of harvesting. The definition of ·farm· now includes facilities that pack or hold food, provided that all food used in such activities is grown, raised, or consumed on that farm or another farm under the same ownership. ·Holding· has been defined and means ·storage of food.· Holding facilities include warehouses, cold storage facilities, storage silos, grain elevators, and liquid storage tanks. ·Packaging· has been defined and means ·the outer packaging of food that bears the label and does not contact the food. Packaging does not include food contact substances as they are defined in section 409(h)(6) of the FD&C Act (21 U.S.C. 348(h)(6)).· Recipe has been defined to mean the formula, including ingredients, quantities, and instructions, necessary to manufacture a food product. Because a recipe must have all three elements, a list of the ingredients used to manufacture a product without quantity information and manufacturing instructions is not a recipe. The partial exclusion for retail food establishments has been replaced with a partial exclusion for persons who distribute food directly to consumers. Persons who distribute food directly to consumers are excluded from establishing and maintaining records required by §.1.345 to identify the nontransporter and transporter immediate subsequent recipients as to those transactions. Persons who distribute food to businesses must establish and maintain records to identify the nontransporter and

transporter immediate subsequent recipients to the extent that information is reasonably available, for example when the purchaser has an established commercial account. The exclusion for retail facilities that are located in the same general physical location as a farm has been replaced with an exclusion for all retail food establishments that employ 10 or fewer full-time equivalent employees. An exclusion has been added for nonprofit food establishments. ·Nonprofit food establishment· has been defined and means: * * * a charitable entity that prepares or serves food directly to the consumer or otherwise provides food or meals for consumption by humans or animals in the United States. The term includes central food banks, soup kitchens, and nonprofit food delivery services. To be considered a nonprofit food establishment, the establishment must meet the terms of section 501(c)(3) of the U.S. Internal Revenue Code (26 U.S.C. 501(c)(3)). The requirement to record a ·responsible individual· when identifying the immediate previous source, immediate subsequent recipient, and transporters has been deleted. The requirement to record ·lot or code number or other identifier· has been deleted for all covered entities, except persons who manufacture, process, or pack food. The definition of perishable food has been deleted.

One commenter misunderstood the meaning of 'maintained' with respect to the Level 1, 2, and 3 provisions. An operational plan of action can be created without risk to the certification validity period. If a security event generates risk for the protection of FCI or CUI, the associated security requirements should be readdressed expeditiously. If one or more of the requirements can't be remediated, the OSA should create an operational plan of action and resolve it in a time frame that continues to provide protection to FCI or CUI. The Accreditation Body must have its own appeals process, as required under ISO/IEC 17011:2017(E). Each C3PAO is required to have an appeals process which involves elevation to the CMMC Accreditation Body for resolution. The appeals process is derived from and consistent with ISO/IEC 17020:2012(E) and ISO/IEC 17011:2017(E). The appeals process is addressed in §§·170.7(b), 170.8(b)(16), and 170.9(b)(13), (19), and (20). An OSC, the CMMC AB, or a C3PAO may appeal the outcome of its DCMA DIBCAC conducted assessment within 21 days of the assessment by submitting a written basis for appeal that include the requirements in question for DCMA DIBCAC consideration. An OSC, the CMMC AB, or a C3PAO should visit www.dcma.mil/DIBCAC to obtain the latest for contact information for submitting appeals. A DCMA DIBCAC Quality Assurance Review Team will respond to acknowledge receipt of the appeal and may request additional supporting documentation. By defining the requirements in this rule to become a C3PAO, and defining a scoring methodology, the DoD is providing the authority and guidance necessary for C3PAOs to conduct assessments. The CMMC Accreditation Body will administer the CMMC Ecosystem. The DoD will not assume the workload of directly managing the CMMC ecosystem or the other alternatives suggested. DoD declines to give the PMO responsibility to render the final decision on all CMMC Level 2 assessment appeals as this role is properly aligned to the CMMC Accreditation Body. The CMMC AB is under contract with the Department of Defense to execute defined roles and responsibilities for the DoD CMMC Program as outlined in §·170.8. The specified CMMC AB requirements were selected and approved by the DoD. They include Conflict of Interest, Code of Professional Conduct, and Ethics policies as set forth in the DoD contract. For ISO/IEC 17020:2012(E) and ISO/IEC 17011:2017(E) compliance, an appeals process is required. CMMC-specific requirements for appeals are addressed in §§·170.8(b)(16) and 170.9(b)(13), (19), and (20). The DoD expects the process to be managed efficiently, however setting a specific timeline is not appropriate as the time may vary based on the complexity of the issue. Responsibility for final appeals determination rests with the CMMC AB. The DoD declines to mandate that the CMMC AB consult with the CMMC PMO or DIBCAC prior to rendering a decision. The CMMC PMO will serve in the oversight role for the entire CMMC program.

note 123, p. 5-10. Back to Citation 433. · See 68 FR 8334 , 8344 (Feb. 20, 2003). Back to Citation 434. · See 45 CFR 164.502(b) and 164.514(d) . Back to Citation 435. 45 CFR 164.308(a)(5)(ii)(A) . Back to Citation 436. 45 CFR 164.308(a)(5)(ii)(B) . Back to Citation 437. 45 CFR 164.308(a)(5)(ii)(C) . Back to Citation 438. 45 CFR 164.308(a)(5)(ii)(D) . Back to Citation 439. 45 CFR 164.308(a)(7)(ii)(A) . Back to Citation 440. 45 CFR 164.308(a)(7)(ii)(B) . Back to Citation 441. 45 CFR 164.308(b)(3) . Back to Citation 442.

See proposed revisions to 45 CFR 164.316 for a more fulsome discussion of documentation requirements. Back to Citation 443. · See proposed revisions to 45 CFR 164.306(c) and (d) for a more fulsome discussion of the distinction between ·required· and ·addressable· implementation specifications. Back to Citation 444. · See ·The NIST Cybersecurity Framework (CSF) 2.0,· supra note 15. Back to Citation 445. · See 78 FR 5566 , 5572-5573 (Jan. 25, 2013) (explaining reasons for adopting proposal to apply the business associate provisions of the HIPAA Rules to subcontractors and thus, provides in the definition of ·business associate· that a business

associate includes a subcontractor that creates, receives, maintains, or transmits protected health information on behalf of the business associate. Back to Citation 446. See, e.g., OCR information about the Change Healthcare cybersecurity incident. Change Healthcare Cybersecurity Incident Frequently Asked Questions, U.S. Department of Health and Human Services (July 30, 2024), <https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/index.html>. Back to Citation 447. See Guidance on HIPAA & Cloud Computing, Office for Civil Rights, U.S. Department of Health and Human Services (A covered entity (or business associate) that engages a [cloud service provider (CSP)] should understand the cloud computing environment or solution offered by a particular CSP so that the covered entity (or business associate) can appropriately conduct its own risk analysis and establish risk management policies, as well as enter into appropriate [business associate agreements.]), <https://www.hhs.gov/hipaa/for-professionals/special-topics/health-information-technology/cloud-computing/index.html>. Back to Citation 448. Cybersecurity Performance Goals, supra note 18. Back to Citation 449. See Letter from NCVHS Chair Jacki Monson (2023), supra note 123, Appendix p. 5. Back to Citation 450. See 68 FR 8333, 8352 (Feb. 20, 2003). Back to Citation 451. See Making a List and Checking it Twice: HIPAA and IT Asset Inventories, Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Aug. 25, 2020), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-summer-2020/index.html>. Back to Citation 452. Id. Back to Citation 453. See The NIST Cybersecurity Framework (CSF) 2.0, supra

This final rule includes additional amendments in response to industry feedback on the proposed rule, which are described in section II.A. of this preamble. In particular, one of the amendments provides alternative forms of security, in lieu of the requirements of paragraph (f) of the clause at FAR 52.232-32. The amendment to the rule will facilitate the use of performance-based payments by contractors that may not have accounting systems designed for FAR part 15 cost-reimbursement work, and contractors without job-cost accounting systems that can associate work in progress with a specific contract. One company expressed (printed page 19687) support for this specific amendment at an E.O. 12866 meeting on the final rule. DoD has performed a regulatory cost analysis on this rule. The following is a summary of the estimated public cost savings and Government costs in millions calculated in perpetuity in 2016 dollars at a 7-percent discount rate:

Summary	Public	Government	Total	Present Value	Annualized Costs
·3.778	·1.914	·1.864	Annualized Value Costs (as of 2016 if Year 1 is 2020)	·2.882	·1.460

·1.422 To access the complete Regulatory Cost Analysis, go to the Federal eRulemaking Portal at www.regulations.gov, search for DFARS Case 2019-D002, click Open Docket, and view Supporting Documents. V. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is a significant regulatory action and, therefore, was subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804. VI. Executive Order 13771 This rule is an E.O. 13771, Reducing Regulation and Controlling Regulatory Costs, deregulatory action. We estimate that this rule generates \$1.4 million in annualized cost savings, discounted at 7 percent relative to year 2016, over a perpetual time horizon. Details on the estimated cost savings can be found in section IV. of this preamble. VII. Regulatory Flexibility Act A final regulatory flexibility analysis (FRFA) has been prepared consistent with the Regulatory Flexibility Act, 5 U.S.C. 601, et seq. The FRFA is summarized as follows: This rule implements section 831 the National Defense Authorization Act (NDAA) for Fiscal Year (FY) 2017, which amends 10 U.S.C. 2307

CIS Safeguard 6.6 Establish and Maintain an Inventory of Authentication and Authorization Systems Establish and maintain an inventory of the enterprise's authentication and authorization systems, including those hosted on-site or at a remote service provider. Review and update the inventory, at a minimum, annually, or more frequently. Implementation Groups: 2,3 Asset Type: users Security Function: identify Parent Control: Access Control Management

To control access to DOD information, information based systems and facilities by authenticating the identity of a person using a measurable physical characteristic(s). This computer system uses

software programs to create biometrics templates and summary statistics, which are used for purposes such as assessing system performance or identifying problem areas. (iii) Routine Use(s): None. The DOD Blanket Routine Uses set forth at the beginning of the Army's Compilations of System of Records Notices applies to this system. (iv) Disclosure: Voluntary; however, failure to provide the requested information may result in denial of access to DOD information based systems and/or DOD facilities. (2) [Reserved]. (printed page 24510) Appendix D to Part 505-Exemptions; Exceptions; and DOD Blanket Routine Uses (a) Special Exemption. 5 U.S.C. 552a(d)(5) Denies individual access to any information compiled in reasonable anticipation of civil action or proceeding. (b) General and Specific Exemptions. The Secretary of the Army may exempt Army systems of records from certain requirements of the Privacy Act. The two kinds of exemptions that require Secretary of the Army enactment are General and Specific exemptions. The Army system of records notices for a particular type of record will state whether the Secretary of the Army has authorized a particular General and Specific exemption to a certain type of record. The Army system of records notices are published in DA Pam 25-51 and on the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy/>. (c) Twelve Exceptions to the No Disclosure without Consent rule of the Privacy Act. (1) 5 U.S.C. 552a(b)(1) To DOD officers and employees who have a need for the record in the performance of their official duties. This is the official need to know concept. (2) 5 U.S.C. 552a(b)(2) FOIA requires release of the information. (3) 5 U.S.C. 552a(b)(3) the Routine Use Exception. The Routine Use must be published in the Federal Register and the purpose of the disclosure must be compatible with the purpose for the published Routine Use. The applicable Routine Uses for a particular record will be listed in the applicable Army Systems Notice. (4) 5 U.S.C. 552a(b)(4) To the Bureau of the Census to plan or carry out a census or survey, or related activity pursuant to Title 13 of the U.S. Code. (5) 5 U.S.C. 552a(b)(5) To a recipient who has provided DA or DOD with advance adequate written assurance that the record will be used solely as a statistical research or reporting record, and the record is to be transferred in a form that is not individually identifiable. (6) 5 U.S.C. 552a(b)(6)

- Risk Assessments - Application Certification / Recertification - Functional Security Requirements
 - Security Specifications - Security Design Reviews - System Tests - Certification / Recertification
 - Personnel Screening - Access Control & Accountability - Compliance Assurance - Contingency Planning - Disaster Recovery - Operations Continuity - Approval of Methodologies - b. Certifying Requirements . Procedures must be established for defining functional security requirements, developing technical security specifications, conducting security design reviews and system tests, certifying and recertifying computer applications processing sensitive or mission-critical information at appropriate phases of the system life cycle, and approving technical security specifications for the acquisition of computing resources or related services. (See paragraph 305 for minimum functional security requirements and certification procedures . - c. Personnel Screening . Personnel who participate in managing, designing, developing, operating, or maintaining computer applications processing sensitive or mission-critical information, or who access automated sensitive or missioncritical information, must be appropriately screened to a level commensurate with the sensitivity, criticality, or value of the information to be accessed or handled and the risk and magnitude of loss or harm that could be caused by the individual. Federal personnel are to be screened in accordance with the Federal Personnel Manual, Section 732. Guidance on screening non-Federal personnel is presented in paragraph 306. - d. Access Protection and Accountability . Appropriate protective measures must be established, to the extent economically and technically feasible, for maintaining personal accountability of individual users granted access to sensitive or mission-critical information and for ensuring that they have access to no more information than they are authorized to access. - e. Compliance Assurance .

Documentation review determines if the technical aspects of policies and procedures are current and comprehensive. These documents provide the foundation for an organization's security posture, but are often overlooked during technical assessments. Security groups within the organization should provide assessors with appropriate documentation to ensure a comprehensive review. Documents to review for technical accuracy and completeness include security policies, architectures, and requirements; standard operating procedures; system security plans and authorization agreements; memoranda of understanding and agreement for system interconnections; and incident response plans. Although port scanners identify active hosts, operating systems, ports, services, and applications, they do not identify vulnerabilities. Additional investigation is needed to confirm the presence of insecure protocols (e.g., Trivial File Transfer Protocol [TFTP], telnet), malware, unauthorized applications, and vulnerable services. To identify vulnerable services, the assessor compares

identified version numbers of services with a list of known vulnerable versions, or perform automated vulnerability scanning as discussed in Section 4.3. With port scanners, the scanning process is highly automated but interpretation of the scanned data is not. The plan should also address the logistical details of the engagement-including the hours of operation for assessors; the clearance or background check level required; a call plan with current contact information, network and security operations centers, and the organization's main point of contact for the assessment; the physical location where assessment activities will originate; and the equipment and tools that will be used to conduct the assessment. Any requirements to inform parent organizations, law enforcement, and a computer incident response team (CIRT) should be identified in the assessment plan.

From the NIST SP 800-172 Rev 3 Final Public Draft: Take the following actions when unauthorized or misconfigured components are detected: [Selection (one or more): disable network access by such components; isolate the components; notify [Assignment: organization-defined personnel or roles]]. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 DISCUSSION 925

- I. All data sources and computing services are considered resources. An enterprise relies on different resources to perform its mission: mobile devices, data stores, compute resources (including virtual), remote sensors/actuators, etc. All these components are resources and need to be considered in a ZTA. Some components (e.g., IoT sensors) may not be able to support some solutions such as configuration agents, application sandboxing, etc. so compensating technologies or alternative mitigations may be needed. If the resource lacks certain security capabilities, the enterprise may need to add a PEP component to provide that functionality. - II. The enterprise monitors and measures the integrity and security posture of all owned and associated resources. This tenet deals with the aspects of cyber hygiene for both enterprise-owned resources and those that may not be owned, but used in an enterprise workflow such as configuration, patching, application loading, etc. The state of resources should be monitored, and appropriate action taken when new information such as a new vulnerability or attack is reported or observed. The confidentiality and integrity of data on the resource should be protected. This requires enterprise admins to know how resources are configured, maintained, and monitored. - III. Access to resources is determined by dynamic policy-including the observable state of client identity, application/service, and the requesting asset-and may include other behavioral and environmental attributes. In zero trust, the default behavior for all resources is to deny all connections and only accept connections that are explicitly allowed by policy. Those authorized to access the resource must still authenticate themselves and prove they meet the enterprise policy to be granted the session. This may include meeting requirements such as client software versions, patch level, geolocation, historical request patterns, etc.

HIPAA Security Rule section 164.308 (Administrative Safeguards) addresses security management process. Covered entities and business associates must implement appropriate safeguards to protect electronic protected health information (ePHI). For security management process, organizations should: 1. Establish and document policies specific to security management process 2. Implement technical and procedural controls 3. Train workforce members on their responsibilities 4. Conduct periodic risk assessments addressing security management process 5. Maintain documentation of compliance efforts Under 45 CFR 164.308, this is a administrative safeguards requirement that applies to all covered entities and business associates that create, receive, maintain, or transmit ePHI.

the round key is a block that is usually represented as a sequence of four words (i.e., 16 bytes). An expansion routine, denoted by KEYEXPANSION(), takes the block cipher key as input and generates the round keys as output. In particular, the input to KEYEXPANSION() is represented as an array of words, denoted by key , and the output is an expanded array of words, denoted by w , called the key schedule.

packages, we first estimate the number of facilities that engage in only intrastate food transportation. Then, we adjust this number to account for domestic air cargo carriers of food shipments and carriers of low-value food packages. Additional records maintenance costs incurred by interstate carriers of intrastate shipments are estimated to be zero since it is unlikely that a transportation establishment would use two sets of recordkeeping practices. To determine the number

of intrastate carriers subject to this final rule but not subject to FMCSA requirements, we take a weighted average of the ratios of local to total general freight trucking in the CBP data under NAICS code 4841, and the local to total specialized freight trucking in the County Business Pattern data under NAICS code 4842. Weights are applied to reflect the importance of local specialized and local general freight in all local trucking to estimate the overall number of intrastate carriers. This computation estimates that 50 percent of all freight carrying trucks are intrastate carriers. Consequently, we assume that 50 percent of all transportation facilities are not already subject to recordkeeping requirements under FMCSA, and will incur the full records redesign and additional records maintenance costs of this regulation. The total number of domestic air cargo carriers of food packages is estimated from NAICS code 481112 in the CBP and NES data which was used for estimating the total number of transporters in the PRIA. Since not all of the carriers reported under NAICS code 481112 transport food items, we used a factor of 50 percent to scale data from the CBP and the NES to estimate the number of air cargo carriers that have a significant portion of their business transporting food items. The resulting estimate of the number of air cargo carrier facilities that transport food items is approximately 1,825 or 0.078 percent of the total number of transporters. These facilities will incur records redesign costs and additional records maintenance costs, in addition to learning costs as a result of this final rule. The number of carriers of low-value food items is estimated using the number of couriers under NAICS code number 49211, which was not included in the PRIA. According to the U.S. Census Bureau, this NAICS includes establishments primarily engaged in providing air, surface, or combined courier delivery services. From the CBP and NES statistics there are approximately 141,931 establishments engaged in courier services. Since this includes courier services that use both air and surface transportation, we reduce this number by 50 percent, under the assumption that only establishments engaged in surface courier services are likely to carry food items, resulting in an estimate of 70,965 surface courier facilities.

ell-known technologies, such as publickey cryptography, digital signatures, and cryptographic hashing algorithms. - [20] Department of Financial Protection & Innovation (2023) Crypto Scam Tracker. Available at <https://dfpi.ca.gov/crypto-scams/> - [21] SecureWeb3 (2024) Crypto Scams List. Available at <https://secureweb3.io/cryptoscams/> - [22] Rektify AI (2023) Attack Playbook. Available at <https://github.com/RektifyAI/attackplaybook/tree/main> - [23] Surge (2023) Learn About Web3. Available at <https://www.surgewomen.io/learn-aboutweb3> - [24] Cointelegraph (2023) DeFi Scams 101: How to avoid the most common cryptocurrency frauds. Available at <https://cointelegraph.com/learn/defi-scams-101-how-to-avoid-the-most-common-cryptocurrency-frauds> - [25] Department of Financial Protection & Innovation (2023) Glossary. Available at <https://dfpi.ca.gov/crypto-scams/#Glossary> - [26] ExpressVPN (2022) Survey: How much time do you waste resetting your passwords? Available at <https://www.expressvpn.com/blog/survey-how-much-time-do-you-waste-resetting-your-passwords/> - [27] Coinbase (2023) Preventing loss of crypto assets with publicly-verifiable encryption and backup. Available at <https://www.coinbase.com/blog/preventing-loss-of-crypto-assets-with-publicly-verifiable-encryption-and> - [28] The New York Times (2021) Tens of billions worth of Bitcoin have been locked by people who forgot their key. Available at <https://www.nytimes.com/2021/01/13/business/tens-of-billions-worth-of-bitcoin-have-been-locked-by-people-who-forgot-their-key.html> - [29] Chainalysis Team (2020) 60% of Bitcoin is Held Long Term as Digital Gold. What About the Rest? Available at <https://www.chainalysis.com/blog/bitcoin-market-data-exchanges-trading/> - [30] Crockett M (2016) The Internet (Never) Forgets. SMU Science and Technology Law Review 19(2), Article 4:151-181. Available at

(1) A consultant will not access classified information off the premises of the using (hiring) contractor except in connection with authorized classified visits. (2) A contractor may only assign a consultant outside the United States with responsibilities requiring access to classified information when: (i) The consultant agreement between the contractor and consultant includes: (A) Identification of the contract, license, or agreement that requires access to classified information, the level of classified information that is required, and access to FGI by the consultant while assigned outside the United States. (B) A formal agreement that prohibits the consultant from disclosing any classified information related to the contract, license, or agreement as required in paragraph (m)(i)(A) of this section to any party other than the USG or foreign government with which the consultant is meeting, and who possesses the requisite clearance and need to know. (ii) The consultant and the using contractor will jointly execute the consultant agreement setting forth respective security responsibilities. The contractor will retain an original signed copy of the agreement and will ensure its availability if requested by the CSA. (iii) The contractor, in consultation with the applicable CSA as appropriate, will determine what threat

briefing(s) the consultant should receive before the assignment, and conduct those briefings as part of the consultant's pre-assignment and recurring security training. (iv) The contractor provides notice of any changes to the consultant agreement to the applicable CSA during assessments or upon CSA request. (3) The using contractor will be the consumer of the consultant services as set forth in the consultant agreement. (4) For security administration purposes, a consultant will be considered an employee of the using contractor for compliance with this rule. (5) Consultants to GCAs are not under the purview of the NISP and will be processed for determination of eligibility by the GCA in accordance with GCA procedures. § 117.11 Foreign Ownership, Control, or Influence (FOCI). (a) General. Foreign investment can play an important role in maintaining the vitality of the U.S. industrial base. Therefore, it is the intent of the USG to allow foreign investment consistent with the national security interests of the United States. The following FOCI (printed page 83331) procedures for cleared U.S. entities are intended to mitigate the risks associated with FOCI by ensuring that foreign firms cannot undermine U.S. security to gain unauthorized access to classified information. (1) The CSA will consider a U.S. entity to be under FOCI when: (i) A foreign interest has the power to direct or decide issues affecting the entity's management or operations in a manner that could either: (A) Result in unauthorized access to classified information; or (B) Adversely affect performance of a classified contract or agreement.

t the Transmission Control Protocol/Internet Protocol (TCP/IP) layers that each is able to examine. TCP/IP communications are composed of four layers that work together to transfer data between hosts. When a user wants to transfer data across networks, the data is passed from the highest layer through intermediate layers to the lowest layer, with each layer adding more information. The lowest layer sends the accumulated data through the physical network, with the data then passed upwards through the layers to its destination. Simply put, the data produced by a layer is encapsulated in a larger container by the layer below it. The four TCP/IP layers, from highest to lowest, are shown in Figure 2-1.

According to Guide to Attribute Based Access Control (ABAC) Definition and Considerations, Executive Summary: (subject and object), operations, and the environment relevant to a request. ABAC systems are capable of enforcing both Discretionary Access Control (DAC) and Mandatory Access Control (MAC) concepts. ABAC enables precise access control, which allows for a higher number of discrete inputs into an access control decision, providing a bigger set of possible combinations of those variables to reflect a larger and more definitive set of possible rules to express policies. The access control policies that can be implemented in ABAC are limited only by the computational language and the richness of the available attributes. This flexibility enables the greatest breadth of subjects to access the greatest breadth of objects without specifying individual relationships between each subject and each object. For example, a subject is assigned a set of subject attributes upon employment (e.g., Nancy Smith is a Nurse Practitioner in the Cardiology Department). An object is assigned its object attributes upon creation (e.g., a folder with Medical Records of Heart Patients) . Objects may receive their attributes either directly from the creator or as a result of automated scanning tools. The administrator or owner of an object creates an access control rule using attributes of subjects and objects to govern the set of allowable capabilities (e.g., all Nurse Practitioners in the Cardiology Department can View the Medical Records of Heart Patients). Under ABAC, access decisions can change between requests by simply changing attribute values, without the need to change the subject/object relationships defining underlying rule sets. This provides a more dynamic access control management capability and limits long-term maintenance requirements of object protections. Further, ABAC enables object owners or administrators to apply access control policy without prior knowledge of the specific subject and for an unlimited number of subjects that might require access.

The Secure Data Network System (SDNS) project, initiated by the National Security Agency in 1986, produced a computer network security architecture within the framework of the International Organization for Standardization (ISO) reference model for Open Systems Interconnection (OSI). The security protocol at layer 4 (SP4) is one element of the SDNS architecture used to provide security services at the Transport Layer of the OSI reference model. This report specifies the Protocol Implementation Conformance Statement (PICS) proforma for SP4. When the PICS proforma is completed for an SP4 implementation, it provides a clear and concise statement of capabilities, useful in a variety of situations to those involved in the production, testing, supply, procurement, and application of the implementation. The Secure Data Network System (SDNS) project, initiated by the National Security Agency in 1986, produced a computer network security architecture within the

framework of the International Organization for Standardization (ISO) reference model for Open Systems Interconnection (OSI) . The security protocol at layer 4 (SP4) is one element of the SDNS architecture used to provide security services at the Transport Layer of the OSI reference model. This report specifies the Protocol Implementation Conformance Statement (PICS) proforma for SP4. When the PICS proforma is completed for an SP4 implementation, it provides a clear and concise statement of capabilities, useful in a variety of situations to those involved in the production, testing, supply, procurement, and application of the implementation.

CM.L2-3.4.5 · Access Restrictions for Change CMMC Assessment Guide · Level 2 | Version 2.13 101
DISCUSSION [NIST SP 800-171 REV. 2]89 Any changes to the hardware, software, or firmware components of systems can potentially have significant effects on the overall security of the systems . Therefore, organizations permit only qualified and authorized individuals to access systems for purposes of initiating changes, including upgrades and modifications . Access restrictions for change also include software libraries . Access restrictions include physical and logical access control requirements, workflow automation, media libraries, abstract layers (e.g., changes implemented into external interfaces rather than directly into systems), and change windows (e.g., changes occur only during certain specified times) . In addition to security concerns, commonly-accepted due diligence for configuration management includes access restrictions as an essential part in ensuring the ability to effectively manage the configuration. NIST SP 800-128 provides guidance on configuration change control. FURTHER DISCUSSION Define, identify, and document qualified individuals authorized to make physical and logical changes to the organization's hardware, software, software libraries , or firmware components. Control of configuration management activities may involve: · physical access control that prohibits unauthorized users from gaining physical access to an asset (e.g., requiring a special key card to enter a server room); · logical access control that prevents unauthorized users from logging onto a system to make configuration changes (e.g., requiring specific credentials for modifying configuration settings, patching software, or updating software libraries); · workflow automation in which configuration management workflow rules define human tasks and data or files are routed between people authorized to do configuration management based on pre-defined business rules (e.g., passing an electronic form to a manager requesting approval of configuration change made by an authorized employee); · an abstraction layer for configuration management that requires changes be made from an external system through constrained interface (e.g., software updates can only be made from a patch management system with a specific IP address); and · utilization of a configuration management change window (e.g., software updates are only allowed between 8:00 AM and 10:00 AM or between 6:00 PM and 8:00 PM). Example Your datacenter requires expanded storage capacity in a server. The change has been approved, and security is planning to allow an external technician to access the building at a specific date and time under the supervision of a manager [a,b,c,d]. A system administrator creates a temporary privileged account that can be used to log into the server's operating system and update storage settings [e,f,g]. On the appointed day , the technician is escorted 89 NIST SP 800-171 Rev. 2, p. 22.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA, DLO ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Expose (Detect) NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 REFERENCES 2189

s of computing platforms, including general purpose computing systems, cyber-physical systems, cloud systems, mobile systems, industrial control systems, and Internet of Things (IoT) devices. Safeguarding measures include both security and privacy controls to protect the critical and essential operations and assets of organizations and the privacy of individuals. The objective is to make the systems we depend on more penetration resistant to attacks, limit the damage from those attacks when they occur, and make the systems resilient, survivable, and protective of individuals' privacy.

The CTR\DRBG\Update function updates the internal state of the CTR\DRBG using the provided_data . The values for blocklen , keylen and seedlen are provided in Table 3 of Section 10.2.1. The value of ctr_len is known by an implementation. The block cipher operation in step 2.2 of the CTR\DRBG\UPDATE process uses the selected block cipher algorithm. The specification of Block_Encrypt is discussed in Section 10.3.3. For this DRBG mechanism, there are two cases for the processing. For each case, let CTR\DRBG\Update be the function specified in Section 10.2.1.2, and let Block_Encrypt be the function specified in Section 10.3.3. The seed length (seedlen) and the

value of `reseed_interval` are provided in Table 3 of Section 10.2.1. The value of `ctr_len` is known by an implementation. Derivation functions are internal functions that are used during DRBG instantiation and reseeding to either derive internal state values or to distribute entropy throughout a bitstring. Two methods are provided. One method is based on the use of hash functions (see Section 10.3.1), and the other method is based on the use of block cipher algorithms (see Section 10.3.2). The block cipher derivation function specified in Section 10.3.2 uses a BCC function and a `Block_Encrypt` call that are discussed in Section 10.3.3.

(v) If the record or information was submitted on a strictly voluntary basis, absent any exercised authority that prescribes criteria for submission, and it is absolutely clear that the record or information would customarily not be released to the public the submitter need not be notified. The Component shall withhold this information under Exemption 4. (2) The coordination provisions of this paragraph apply to the release of responsive information received from multi-national organizations, such as the North Atlantic Treaty Organization (NATO), United Nations Commands, the North American Aerospace Defense Command (NORAD), the Inter-American Defense Board, foreign governments, or international organizations (e.g., the International Committee of the Red Cross). (i) Coordination with foreign governments under the provisions of this paragraph may be made through the Department of State, the specific foreign embassy, or any other coordination channel the Component has established. OFOI has established a coordination channel with the United Kingdom Ministry of Defence (MOD). If the DoD Component has MOD-originated information within its files, it shall be forwarded to OFOI, which shall coordinate with the MOD for release. The MOD release recommendation will be forwarded by OFOI back to the Component for direct response to the requester. Coordination with most international organizations may be made directly with those organizations. However, for NORAD coordination the Components shall refer the documents to the FOIA Office at the United States Northern Command, which will consult with NORAD. (ii) If an international organization or foreign government asks the Department of Defense to withhold classified information originated by the multi-national organization or foreign government, it will be withheld under the provisions of Exemption 1. (iii) If the DoD Component is asked to withhold sensitive unclassified information originated by the multi-national organization or foreign government, then the Component will withhold it under the provisions of Exemption 3, and shall reference the relevant statute as 10 U.S.C. 130c. To qualify for withholding under this statute, the Component IDA must make the three following determinations concerning the requested foreign information: (A) The information was provided by or produced in cooperation with a foreign government or international organization. (B) The information is withheld from public disclosure by the foreign government or international organization (the foreign government or international organization should make this representation in writing). (C) Any of the following three conditions are met: (1) The foreign government or international organization requests in writing that the information be withheld. (2) The foreign government or international organization provides the information to the U.S. Government on the condition that it not be released to the public. (3

CUI handling is governed by 32 CFR Part 2002 and the ISOO CUI Marking Handbook (Version 1.1). Organizations must implement NIST SP 800-171 controls to protect CUI and follow marking requirements: - Banner markings (CUI designation at top and bottom of pages/documents) - Portion markings (optional, marking individual sections with (CUI)) - Dissemination controls where applicable - Proper handling, storage, and destruction procedures For specific marking guidance, consult the ISOO CUI Marking Handbook and your organization's CUI handling procedures. Under DFARS 252.204-7012, any incident involving potential CUI compromise must be reported to DC3 within 72 hours.

8 (also known as the Common Criteria) provides functionality and assurance requirements for developers of information systems and information system components (i.e., information technology products). Since many of the technical security controls defined in Appendix F are implemented in hardware, software, and firmware components of information systems, organizations can obtain significant benefit from the acquisition and employment of information technology products evaluated against the requirements of ISO/IEC 15408. The use of such products can provide evidence that certain security controls are implemented correctly, operating as intended, and producing the desired effect in satisfying stated security requirements.

- FIPS 140-2, Security Requirements for Cryptographic Modules - FIPS 197, Advanced Encryption Standard (AES) - FIPS 199, Standards for Security Categorization of Federal Information and

Information Systems - FIPS 201-2, Personal Identity Verification (PIV) of Federal Employees and Contractors - SP 800-12 Rev. 1, An Introduction to Information Security - Draft SP 800-16 Rev. 1, A Role-Based Model for Federal Information Technology/Cybersecurity Training - SP 800-18 Rev. 1, Guide for Developing Security Plans for Federal Information Systems - SP 800-30 Rev. 1, Guide for Conducting Risk Assessments - SP 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems - SP 800-39, Managing Information Security Risk: Organization, Mission, and Information System View - SP 800-40 Rev. 3, Guide to Enterprise Patch Management Technologies Advanced Encryption Standard - [1] NIST Special Publication (SP) 800-125, Guide to Security for Full Virtualization Technologies, National Institute of Standards and Technology, Gaithersburg, Maryland, January 2011, 35pp. <https://doi.org/10.6028/NIST.SP.800-125>.

- o management procedures and controls; - o physical, data, operating system, application software, personnel, and network security; and - o disaster recovery. The Contractor shall examine the management procedures that support security. This includes a study of the organization chart, the authorities and responsibilities, and the separation of functions. The Contractor shall also provide a list of management controls to be reviewed in each area (general, physical, data, and system and application software). This list shall, at a minimum, include: ## Task 3 -Review Physical Security

Comment: Obligations of non-PSC prime contractors Response: The definition of covered contract has been reworded to cover contracts for the performance of services and/or the delivery of supplies. Comment: IFR applicability to contingency operations in the U.S. and distinction between combat operations and contingency operations Response: The Rule does not apply to operations within the United States. We have clarified this in the definition of covered contract. Comment: Applicability to foreign actors Response: When applicable conditions are met, the Rule covers all companies and personnel providing private security functions, regardless of the country of registration of the company or national origin of its employees. We believe that this is already made clear by sections 159.2 (b)(1) and (2) which state the policy prescription. The Rule applies to government entities and prescribes policies for the oversight and management of PSCs and PSC personnel. The clause in section 159.2 (2)(a)(2) starting with specifically describes the conditions under which this part would apply beyond DoD, to DoS and other Federal agencies. The acquisition regulations, rather than this rule, will serve as the implementing mechanisms for PSC companies. Comment: Further define intelligence operations Response: This language implements Section 862 (d) of the FY 2008 NDAA. Comment: Active non-lethal countermeasure would benefit from a clear definition and examples Response: The following clarification has been added to the Rule: Active non-lethal systems include laser optical distracters, acoustic hailing devices, electro-muscular TASER guns, blunt-trauma devices like rubber balls and sponge grenades, and a variety of riot-control agents and delivery systems. Comment: Definition of Contingency Operation is a slight variation of the definition of contingency operation in FAR 2.101 Response: The definition in the Rule has been updated; it is taken verbatim from U.S. Code Title 10, 101(a)(13). Comment: Definition of Covered Contract excludes temporary arrangements outside of DoD for private security functions when contracted for by a non-DoD contractor or a grantee Response: The genesis for this provision was a USAID concern that development projects undertaken by USAID may engage local personnel as security on an ad hoc basis, and that such arrangements should be excluded from complying with the requirements of this regulation. These arrangements cannot realistically be regulated in the same manner as traditional contracts.

(F) Consistent with the legislative purpose of the Privacy Act of 1974, the NRO will grant access to nonexempt material in the records being maintained. Disclosure will be governed by NRO's Privacy Regulation, but will be limited to the extent that the identity of confidential sources will not be compromised; subjects of an investigation of an actual or potential criminal or civil violation will not be alerted to the investigation; the physical safety of witnesses, informants and law enforcement personnel will not be endangered; the privacy of third parties will not be violated; and that the disclosure would not otherwise impede effective law enforcement. Whenever possible, information of the above nature will be deleted from the requested documents and the balance made available. The controlling principle behind this limited access is to allow disclosures except those indicated in this paragraph. The decisions to release information from these systems will be made on a case-by-case basis. (6) System identifier and name. NRO-21, Personnel Security Files. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as

a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and/or (k)(5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (H) and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons. (A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation or prosecutable interest by the NRO or other agencies. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence. (printed page 14790)

3.1.4 | Backdoors and Unpatched Vulnerabilities ... 3.1.4 Backdoors and Unpatched Vulnerabilities
Backdoors and unpatched vulnerabilities could be used either directly or indirectly to bypass other security controls.

Seagate continues to develop a risk-resilient culture within their own organization and throughout their supply chain. Through investments in supply chain-oriented risk metrics and new PSO team tool development, the company aims to remain a leader in the C-SCRM space and continue to provide actionable insight for supply chain interdependencies.

Use of the definition of ‘food’ in section 201(f) of the FD&C Act is consistent with the language of section 306 of the Bioterrorism Act. Section 306 does not contain language qualifying the meaning of food. Furthermore, section 414(b) of the FD&C Act authorizes the Secretary to require certain records to identify the immediate previous sources and recipients of ‘food, including its packaging.’ In addition, section 306(b) of the Bioterrorism Act amended section 704(a) of the FD&C Act, governing factory inspections, to provide that in the case of persons engaging in covered activities with regard to ‘foods, the inspection shall extend to all records and other information described in section 414* * *’. The inspection referenced in section 306(b) of the Bioterrorism Act is one of ‘any factory, warehouse or establishment in which [food] is manufactured, processed, packed or held* * *’. FDA’s longstanding interpretation is that ‘food’ in section 704 of the FD&C Act has the same meaning as in section 201(f) of the FD&C Act. Use of the definition of ‘food’ in section 201(f) of the FD&C Act is also consistent with other sections of the Bioterrorism Act. Section 414(a) of the FD&C Act refers to an article of food that is ‘adulterated.’ ‘Adulterated’ is defined in section 402 of the FD&C Act (21 U.S.C. 342), and ‘food’ in that section has the meaning provided in section 201(f) of the FD&C Act. See, e.g., *Natick Paperboard Corp. v. Weinberger* , 525 F.2d 1103 (1st Cir. 1975). Furthermore, using the definition of ‘food’ in section 201(f) of the FD&C Act for section 306 is consistent with the interpretation of ‘food’ in section 303 of the Bioterrorism Act, providing for administrative detention. When the Secretary has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals, FDA may need to administratively detain the food under section 303 of the Bioterrorism Act and access relevant records under section 306 of the Bioterrorism Act. FDA is therefore retaining its interpretation of ‘food’ in section 306 of the Bioterrorism Act to mean ‘food’ as defined in section 201(f) of the FD&C Act. Food subject to section 306 of the Bioterrorism Act thus includes, but is not limited to, fruits, vegetables, fish, dairy products, eggs, raw agricultural commodities for use as food or components of food, animal feed (including pet food), food and feed ingredients and additives (including substances that migrate into food from food packaging and other articles that contact food, dietary supplements and dietary ingredients), infant formula, beverages (including alcoholic beverages and bottled water), live food animals (such as hogs and elk), bakery goods, snack foods, candy, and canned foods.

The general methodology used to estimate security costs incurred by contractor cleared facilities with approved storage of classified information is based on the costs incurred by respondent contractors for the protection of classified information. The methodology captures the most significant portion of industry’s costs, which is labor. Security labor in the survey is defined as personnel whose positions exist to support operations and staff in the implementation of government

security requirements for the protection of classified information. Guards who are required as supplemental controls are included in security labor. The respondent contractors are requested to compile their cleared facility's current annual security labor cost in burdened, current year dollars with the most recent data being from the 2017 survey. The labor cost, when identified as an estimated percent of each contractor's total security costs, enables the respondent contractors to calculate their total security costs. Information collected is compiled to create an aggregate estimated cost of NISP classification-related activities. Only the aggregate data is reported. The full enterprise industrial security total baseline cost in the December 21, 2020, rule was estimated to not exceed \$1.486 billion for fiscal year 2017. Based on the data collected from the survey, we can be 95% confident the true 2017 total NISP security cost for contractor facilities with approved classified storage is less than \$1.486 billion. Public Cost Analysis of the Changes to the Baseline From This Rule

1. Cost Analysis. Throughout, labor rates are adjusted upward by 100% to account for overhead and benefits. The following areas, 1.a and 1.b, were re-evaluated for cost based on the public comment.

a. Train all cleared employees on requirements to submit foreign travel reports. We determined that the estimate of cleared contractor personnel who would be required to be trained should also include TOP SECRET cleared employees rather than just SECRET cleared employees as indicated in the original rule. The FSO at each entity (small or large) must ensure that its cleared employees are trained on the requirements. Such training by the FSO is estimated to take one hour in 2021 and a half an hour in each of the following years up to the 20th year. Using the published Office of Personnel Management GS salary schedule for FY20, the estimated labor rate for an FSO of a small business entity firm is the equivalent of a GS11 step 5 and for an FSO of a large business entity is the equivalent of a GS13, step 5. These assumptions imply total costs of \$0.99 million in 2021 as year one; and, \$0.49 million each year from year two through the 20th year. These estimates have not changed from the original baseline.

Van Wyk, who reviewed drafts of this document. Additionally, the authors would like to thank Mr. Art Friedman (NSA) and Mr. Paul Jacob (Booz Allen Hamilton, Linthicum, MD) for initiating this effort. The authors also gratefully acknowledge and appreciate the comments and contributions made by government agencies, private organizations, and individuals in providing direction and assistance in the development of this document.

Multi-Regional HIEs connect multiple Regional HIEs. They may cross state lines or other physical boundaries. They are usually EHR-based. Since they connect multiple Regional HIEs, they will likely have a federated technical architecture. For Multi-Regional HIEs, conflicts of laws may require complex solutions. not, for example, be obliged to disclose health information about mental or physical abuse to the patient's possible abuser. As this measure allows the patient even more protection than HIPAA explicitly allows, it is 'more stringent' and should be followed.

promoting declassification and public access to information as soon as national security considerations permit. ISOO issues implementing directives and produces an annual report to the President on the NISP. E.O. 12829 also established the National Industrial Security Program Policy Advisory Committee (NISPPAC), a federal advisory committee comprised of both Government and industry representatives, which is responsible for recommending changes in industrial security policy. The NISPPAC, chaired by the Director of the ISOO, also advises ISOO on all issues concerning the policies of the NISP, including recommended changes to those policies, and serves as a forum to discuss policy issues in dispute. The NISPPAC industry members represent all types and sizes of NISP cleared entities, whose scope of operations range from a one person entity, having a single classified contract to some of the largest U.S. entities, having numerous classified contracts. All NISPPAC industry members have expertise comprising the primary functions of an industrial security program, to include information, personnel, physical, and information system security. Five USG executive branch agencies·DoD, DOE, the Nuclear Regulatory Commission (NRC), the Office of the Director of National Intelligence (ODNI), and the Department of Homeland Security (DHS)·have been designated as Cognizant Security Agencies (CSAs) and have specific responsibilities within the NISP. For DoD, the Defense Counterintelligence and Security Agency (DCSA) is the Cognizant (printed page 83301) Security Office (CSO) for DoD Components and non-DoD agencies where an industrial security agreement is in place. DCSA, as the DoD CSO, DOE, and NRC each has the following responsibilities: Administers the NISP. provides security oversight. conducts security review actions. provides security education and training. provides supplementary procedures for unique mission requirements (e.g. DoD publishes industrial security letters (ISLs), which provide DoD-specific guidance and clarification on NISP policies and supplementary procedures to its unique CSO

mission requirements (available at: <https://www.dcsa.mil/mc/ctp/tools/>). assesses, authorizes and oversees contractor information systems used to process classified information. makes temporary national security eligibility determinations pursuant to SEAD 8, Temporary Eligibility (available at: https://www.dni.gov/files/NCSC/documents/Regulations/SEAD-8_Temporary_Eligibility_U.pdf), for contractor personnel who require access to classified information. DHS receives NISP industrial security services from DoD due to its industrial security services agreement and also has the following responsibilities: Prescribes procedures for the portions of this rule that pertain to the CCIPP. retains authority over access to information under the CCIPP. inspects and monitors contractor, licensee, certificate holder, and grantee programs and facilities that involve access to CCIPP.

Attribute Considerations for Access Control Systems ## Attribute Considerations for Access Control Systems This document provides federal agencies with a guide for implementing attributes in access control systems. Attributes enable a logical access control methodology where authorization to perform a set of operations is determined by evaluating attributes associated with the subject, object, requested operations, and, in some cases, environment conditions against policy, rules, or relationships that describe the allowable operations for a given set of attributes. This document outlines factors which influence attributes that an authoritative body must address when standardizing an attribute system and proposes some notional implementation suggestions for consideration.

(6) Not be under FOCI to such a degree that a favorable entity eligibility determination for access to classified information would be inconsistent with the national interest, in the judgment of the CSA. (7) Maintain sufficient authorized and cleared employees to manage and implement the requirements of this rule in accordance with CSA guidance. (8) Not pose an unacceptable risk to national security interests, in the judgment of the CSA. (9) Meet all requirements governing access to classified information established by the CSA or the relevant authorizing law, regulation, or government-wide policy. (d) Processing the entity eligibility determination. The CSA will assess the entity's eligibility for access to classified information based on its business structure. (1) At a minimum, the entity will: (i) Provide CSA-requested documentation within timelines established by the CSA. (ii) Have and identify the SMO. (iii) Appoint a U.S. citizen employee as the FSO. (iv) Appoint a U.S. citizen employee as the ITPSO. (v) Submit requests for personnel security investigations for the SMO, FSO, ITPSO, and those other KMP identified by the CSA as requiring eligibility for access to classified information in connection with the entity eligibility. (2) If the entity is under FOCI with a special security agreement (SSA) as the proposed method of FOCI mitigation, and the GCA requires the entity to have access to proscribed information, the CSA must consider the measures listed in § 117.11(d) as part of the entity eligibility determination. (e) Other personnel eligibility determinations concurrent with the entity eligibility determination. (1) Contractors may designate employees who require access to classified information during the negotiation of a contract or the preparation of a bid or quotation pertaining to a prime contract or a subcontract. These designated employees will be processed for a determination of eligibility for access to classified information (i.e., PCL eligibility) concurrent with entity's entity eligibility determination. (2) The entity eligibility determination is not dependent on the PCL eligibility for access to classified information by such employees, provided none of these employees are among those listed in paragraph (c)(5) of this section. Even so, the employees will not be granted access to classified information until both a favorable entity eligibility determination and PCL eligibility has been granted. (f) Exclusion procedures. If a CSA determines that certain KMP can be excluded from access to classified information, the contractor will follow the procedures in accordance with § 117.7(b)(5)(ii). (g) Temporary exclusions. As a result of a changed condition, the SMO or other KMP who require eligibility for access to classified information in connection with the facility entity eligibility determination may be temporarily excluded from access to classified information while in the process of a PCL eligibility determination provided:

(3) The CSA will promptly advise the parties in a transaction under CFIUS review that would require FOCI negation or mitigation measures if consummated, to submit to the CSA a plan to negate or mitigate FOCI. If it appears that an agreement cannot be reached on material terms of a FOCI action plan, or if the U.S. person that is a party, or in applicable cases, a subject of the proposed transaction fails to comply with the FOCI reporting requirements of this rule, the CSA may recommend a full investigation of the transaction by the CFIUS to determine the effects on national security.

§-117.12 Security training and briefings. (a) General. Contractors will provide all cleared employees with security training and briefings commensurate with their involvement with classified information. (b) Training materials. Contractors may obtain security, threat awareness, and other education and training information and material from their CSA or other sources. (c) Government provided briefings. The CSA is responsible for providing initial security briefings to the FSO and for ensuring other briefings required for special categories of information are provided to the FSO. (d) FSO training. Contractors will ensure the FSO and others performing security duties complete training considered appropriate by the CSA. Training requirements will be based on the contractor's involvement with classified information. Training may include an FSO orientation course, and for FSOs at contractor locations with a classified information safeguarding capability, an FSO program management course. Contractor FSOs will complete training within six months of appointment to the position of FSO. When determined by the applicable CSA, contractor FSOs must complete an FSO program management course within six months of the CSA approval to store classified information at the contractor. (e) Initial security briefings. Prior to being granted access to classified information, contractors will provide employees with an initial security briefing that includes: (1) Threat awareness, including insider threat awareness in accordance with paragraph (g) in this section. (2) Counterintelligence (CI) awareness. (3) Overview of the information security classification system. (4) Reporting obligations and requirements, including insider threat. (5) Cybersecurity training for all authorized information system users in accordance with CSA-provided guidance pursuant to §-117.18(a)(1) and (a)(2). (6) Security procedures and duties applicable to the employee's position requirements (e.g. marking and safeguarding of classified information) and criminal, civil, or administrative consequences that may result from the unauthorized disclosure of classified information, even though the individual has not yet signed an NDA. (f) CUI training. While outside the requirements of the NISPOM, when a classified contract includes provisions for CUI training, contractors will comply with those contract requirements. (g) Insider threat training.

The DIB CS/IA program collects Point of Contact (POC) information from DIB participants. POC information is needed to facilitate communication between DoD and DIB participants, as well as prospective participants. The POC information includes the names, security clearance information, citizenship, work addresses, including division/group, work email addresses and work telephone numbers of company-identified representatives. DIB POCs include the Chief Executive Officer (CEO), Chief Information Officer (CIO), Chief Information Security Officer (CISO), General Counsel, the Chief Privacy Officer, and the Corporate Security Officer (CSO) or Facility Security Officer (FSO), or their equivalents. DIB participants also provide POC information for personnel responsible for the implementation and execution of the DIB CS/IA program within their company including designated personnel authorized to report incidents and any policy, administrative, or technical personnel identified to interact with DOD in the operational implementation of the program. Affected Public: Business or other for-profit and not-for-profit institutions participating in the voluntary DIB CS/IA program. Frequency: On occasion. Respondent's Obligation: Voluntary. (b) Title: DIB Cyber Security/Information Assurance Cyber Incident Reporting. Type of Request: New. Phased expansion of DIB CS/IA Number of Participants increases to 750 over three years. Projected Responses per Participant: 5. Annual Responses: Year 1 responses are 1,250. Year 2 responses are 2,500. Year 3 responses are 3,750. Average Burden per Response: 7 hours (this includes searching existing data sources, gathering and maintaining the data needed, and completing and reviewing the collection of information). Annual Burden Hours: Year 1 burden hours are 8,750 hours. Year 2 burden hours are 17,500 hours. Year 3 burden hours are 26,250 hours. Needs and Uses: The collection of this information is necessary to enhance and supplement DIB participants' information security capabilities to safeguard DoD information that resides on, or transits, DIB unclassified (printed page 27618) information systems. The requested information supports the information assurance objectives, cyber threat information sharing, and incident reporting between DoD and the DIB participants. In most cases, DIB participants report incidents using a DIB CS/IA standardized Incident Collection Form (ICF). In some cases, a company may elect to report the incident without using the ICF; and companies may report incidents through a variety of communications channels, including email, fax, or by phone, if necessary. Affected Public: Business or other for-profit and not-for-profit institutions participating in the DIB CS/IA program. Frequency: On occasion. Respondent's Obligation: Voluntary. OMB Desk Officer:

would apply to a technology asset currently used by a regulated entity that does not support encryption according to prevailing cryptographic standards. Because the requirements for encryption under the Security Rule today are addressable, a regulated entity may be in compliance with the

encryption requirement without actual encryption of ePHI if encryption is not reasonable and appropriate, provided that the entity meets certain conditions. Additionally, technology assets in use today may rely on cryptographic standards that are no longer accepted industry practice. The Department recognizes that it may take some time for a regulated entity to adopt compliant technology assets. Thus, we propose this exception for such technology assets that do not support encryption consistent with prevailing cryptographic standards in limited circumstances. Specifically, to meet this exception, a regulated entity would be required to establish a written plan to migrate ePHI to technology assets that support encryption consistent with prevailing cryptographic standards and to implement such plan. The regulated entity would be required to establish and implement the written plan within (printed page 969) a reasonable and appropriate period of time. For example, it would not be reasonable or appropriate for a regulated entity to establish a plan to migrate ePHI on a single flash drive within 30 days and not complete migration of that ePHI for a period of a year because migrating ePHI from a flash drive to a more secure medium is a simple and quick process that the regulated entity already determined could be completed within 30 days. Thus, a year would be an unreasonably long period to leave ePHI insufficiently encrypted, particularly after a need to migrate the ePHI has been established. In such circumstances, the regulated entity would not be complying with the requirements of this proposed exception. The second proposed exception at proposed 45 CFR 164.312(b)(3)(ii) would be available for ePHI transmitted in response to an individual request, pursuant to 45 CFR 164.524 , to receive their ePHI in an unencrypted manner. Unencrypted manners for an individual to receive their ePHI may include some types of text messaging, instant messaging, and other applications on a smartphone or another computing device that are capable of making an access request and receiving ePHI. [735] This exception for individual access requests under 45 CFR 164.524 would not apply when the individual would receive their ePHI using technology controlled by the regulated entity, such as a patient portal [736] or other technology for the transmission of ePHI (e.g., API technology). [737] Such email or messaging technologies are considered to be among a covered entity's technology assets because they are components of a covered entity's relevant electronic information systems, and the requirement to encrypt ePHI would apply.

Further, some comments assert that the regulations are directed toward enabling the Government to trace a product, rather than ensuring that companies are able to trace the product through all the links in the chain of custody of a food ingredient or product. The comments state that the intent of the Bioterrorism Act was to ensure the existence of a system that fully engages the institutional knowledge and logical procedures that already enable the companies responsible for the production and distribution of food to maintain an orderly and efficient nationwide supply chain and that also currently make it possible to effect rapid recalls when necessary. The comments state that the proposed regulations fail to capitalize on the efficiencies of time and resources available through effective public/private coordination, exemplified by the efforts that currently support effective recalls. (Response) FDA recognizes that some of the food industry currently has existing records that may satisfy all or part of these regulations; however, not all of the food industry is currently able to conduct such traceback investigations. Notwithstanding the ability of some of the food industry to conduct such investigations, Congress authorized FDA through the Bioterrorism Act to issue regulations requiring the establishment and maintenance of records by persons who manufacture, process, pack, transport, distribute, receive, hold or import food to enable FDA to identify the immediate previous sources and immediate subsequent recipients of food, including its packaging, to address credible threats of serious adverse health consequences or death to humans or animals. FDA believes the information required to be established and maintained in records in these regulations is necessary to enable FDA to conduct an efficient and effective tracing investigation, independent of what the food industry may be able to do. FDA reiterates that it is not dictating the form or type of system to be used to satisfy these requirements in these regulations. If the food industry already keeps all of the information required by this final rule, then existing records can be used to comply with this final rule. Further, FDA anticipates working closely with the food industry in any tracing investigation.

This rule will apply to small businesses that are awarded Government contracts, other than those that receive awards exclusively for COTS items. According to award data in the Federal Procurement Data System (FPDS) for fiscal years (FY) 2021 through FY 2023, on average per year the Government awards contracts and orders for supplies and services (excluding those for supplies purchased using commercial item procedures) to 67,547 unique contractors, of which 44,152 (65 percent) are small businesses. When an SF XXX is incorporated in the contract and identifies CUI that will be involved

in the contract, the contractor will be subject to the new FAR clause at FAR 52.204-XX and more robust compliance requirements for safeguarding the CUI. Per the FPDS data, of the contractors that receive covered awards each year, approximately 37,933 are non-defense contractors and 29,614 are defense contractors, or contractors that do business with both civilian agencies and DoD. Based on consultation with subject matter experts, it is assumed that 18 percent of non-defense contractors (6,828) and 28 percent of defense contractors (8,292), or 15,120 total contractors, may receive awards each year that include an SF XXX listing CUI and the associated safeguarding requirements. It is further assumed that the ratio of subcontractors to prime contractors that handle CUI is 0.5:1, or 7,560 total subcontractors. Therefore, each year, an estimated 22,680 contractors and subcontractors, of which 15,809 (70 percent) are estimated to be small businesses, will be required to safeguard CUI in performance of a contract, pursuant to the new clause at FAR 52.204-XX and the instructions provided on an SF XXX. These small entities may be impacted by the various compliance requirements in the clause, depending on the type of CUI required to be handled under the contract or subcontract, the way in which the information will be handled, and whether those small businesses have already been safeguarding sensitive Government information under other contract provisions. The new FAR clause at 52.204-XX is modeled after the existing clause at DFARS 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, the most recent version of which has been in effect since 2017 (the clause has been in effect since 2013, and the NIST SP 800-171 requirements were added in 2015). As such, small businesses that do business with DoD and handle CUI in performance of their contracts are already subject to requirements equivalent to the new FAR clause and provision. In addition, small businesses that do business with other agencies that have included similar or overlapping safeguarding requirements under agency-specific contract terms may already be in partial or substantial compliance with the clause requirements. The following specific compliance requirements will apply to all Federal offerors, contractors, and subcontractors: Review and Distribute the SF XXX.

CIS Control 4 · Secure Configuration of Enterprise Assets and Software Establish and maintain the secure configuration of enterprise assets (end-user devices, including portable and mobile; network devices; non-computing/IoT devices; and servers) and software (operating systems and applications). As delivered from manufacturers and resellers, the default configurations for enterprise assets and software are normally geared towards ease-of-deployment and ease-of-use rather than security. Basic controls, open services and ports, default accounts or passwords, pre-configured Domain Name System (DNS) settings, older (vulnerable) protocols, and pre-installation of unnecessary software can all be exploitable if left in their default state. Further, these security configuration updates need to be managed and maintained over the life cycle of enterprise assets and software. Configuration updates need to be tracked and approved through configuration management workflow process to maintain a record that can be reviewed for compliance, leveraged for incident response, and to support audits. This CIS Control is important to on-premises devices, as well as remote devices, network devices, and cloud environments. Service providers play a key role in modern infrastructures, especially for smaller enterprises. They often are not set up by default in the most secure configuration to provide flexibility for their customers to apply their own security policies. Therefore, the presence of default accounts or passwords, excessive access, or unnecessary services are common in default configurations. These could introduce weaknesses that are under the responsibility of the enterprise that is using the software, rather than the service provider. This extends to ongoing management and updates, as some Platform as a Service (PaaS) only extend to the operating system, so patching and updating hosted applications are under the responsibility of the enterprise. Even after a strong initial configuration is developed and applied, it must be continually managed to avoid degrading security as software is updated or patched, new security vulnerabilities are reported, and configurations are tweaked, to allow the installation of new software or to support new operational requirements.

additional information collection requirements to the paperwork burden previously approved under the Office of Management and Budget (OMB) Control Number 0704-0567, entitled "Department of Defense Contract Security Classification Specification". The rule addresses use of CAGE codes on the DD Form 254, however, it does not impact information collection requirements concerning the CAGE code, OMB Control Number 9000-0185, Commercial and Government Entity Code. List of Subjects in 48 CFR Parts 1, 2, 4, 52, and 53 Government procurement William F. Clark, Director, Office of Government-wide Acquisition Policy, Office of Acquisition Policy, Office of Government-wide Policy. Therefore, DoD, GSA, and NASA amend 48 CFR parts 1, 2, 4, 52, and 53 as set forth below: 1. The authority citation for 48 CFR parts 1, 2, 4, 52, and 53

continues to read as follows: Authority: 40 U.S.C. 121(c) ; 10 U.S.C. chapter 137 ; and 51 U.S.C. 20113 . PART 1-FEDERAL ACQUISITION REGULATIONS SYSTEM 2. In section 1.106 amend the table following by adding an entry for ·DD Form 254· at the end of the table to read as follows: 1.106 OMB approval under the Paperwork Reduction Act. FAR segment OMB control No. *.....* DD Form 254 0706-0567 PART 2-DEFINITIONS OF WORDS AND TERMS 3. In section 2.101, amend paragraph (b) by adding in alphabetical order the defined term ·Commercial and Government Entity (CAGE) code· to read as follows: 2.101 Definitions. * * * * * Commercial and Government Entity (CAGE) code means· (1) An identifier assigned to entities located in the United States or its outlying areas by the Defense Logistics Agency (DLA) Commercial and Government Entity (CAGE) Branch to identify a commercial or government entity by unique location; or (2) An identifier assigned by a member of the North Atlantic Treaty Organization (NATO) or by the NATO Support and Procurement Agency (NSPA) to entities located outside the United States and its outlying areas that the DLA Commercial and Government Entity (CAGE) Branch records and maintains in the CAGE master file. This type of code is known as a NATO CAGE (NCAGE) code. * * * * * PART 4-ADMINISTRATIVE AND INFORMATION MATTERS 4. Amend section 4.402 by· a. Removing from paragraph (b) introductory text ·and the Director of Central Intelligence,· and adding ·the Director of National Intelligence, and the Secretary of Homeland Security· in its place; b. Removing from paragraph (b)(2) ·Industrial Security Regulation (DOD 5220.22-R)· and adding ·DoD Manual 5220.22, Volume 2, ·National Industrial Security Program: Industrial Security Procedures for Government Activities...· in its place; and c. Redesignating paragraph (d) as (e), and adding a new paragraph (d) to read as follows: 4.402 General. * * * * *

). The guidance represents the Agency's current thinking on medical device classification product codes. It does not create or confer any rights for or on any person and does not operate to bind FDA or the public. An alternative approach may be used if such approach satisfies the requirements of the applicable statute and regulations. III. Electronic Access Persons interested in obtaining a copy of the guidance may do so by using the Internet. A search capability for all CDRH guidance documents is available at <http://www.fda.gov/MedicalDevices/DeviceRegulationandGuidance/GuidanceDocuments/default.htm> . Guidance documents are also available at <http://www.regulations.gov> or from CBER at <http://www.fda.gov/BiologicsBloodVaccines/GuidanceComplianceRegulatoryInformation/default.htm> . To receive ·Medical Device Classification Product Codes,· you may either send an email request to dsmica@fda.hhs.gov to receive an electronic copy of the document or send a fax request to 301-847-8149 to receive a hard copy. Please use the document number 1774 to identify the guidance you are requesting. IV. Paperwork Reduction Act of 1995 This guidance refers to previously approved collections of information found in FDA regulations. These collections of information are subject to review by the Office of Management and Budget (OMB) under the Paperwork Reduction Act of 1995 (44 U.S.C. 3501-3520). The collections of information in 21 CFR part 803, subpart A through E , have been approved under OMB control number 0910-0437; the collections of information in 21 CFR part 807, subpart E , have been approved under OMB control number 0910-0120; and the (printed page 21613) collections of information under 21 CFR part 814 have been approved under OMB control number 0910-0231. V. Comments Interested persons may submit either electronic comments regarding this document to <http://www.regulations.gov> or written comments to the Division of Dockets Management (see ADDRESSES). It is only necessary to send one set of comments. Identify comments with the docket number found in brackets in the heading of this document. Received comments may be seen in the Division of Dockets Management between 9 a.m. and 4 p.m., Monday through Friday, and will be posted to the docket at <http://www.regulations.gov> . Dated: April 5, 2013. Leslie Kux, Assistant Commissioner for Policy. [FR Doc. 2013-08442 Filed 4-10-13; 8:45 am] BILLING CODE 4160-01-P

Guidelines for the Authorization of Personal Identity Verification Card Issuers (PCI) and Derived PIV Credential Issuers (DPCI) ## Guidelines for the Authorization of Personal Identity Verification Card Issuers (PCI) and Derived PIV Credential Issuers (DPCI) The purpose of this Special Publication is to provide appropriate and useful guidelines for assessing the reliability of issuers of Personal Identity Verification (PIV) Cards and Derived PIV Credentials. These issuers store personal information and issue credentials based on Office of Management and Budget (OMB) policies and on the standards published in response to Homeland Security Presidential Directive 12 (HSPD-12) and therefore are the primary target of the assessment and authorization under this guideline. The reliability of an issuer is of utmost importance when one organization (e.g., a federal agency) is required to trust the identity credentials of individuals that were created and issued by another

federal agency. This trust will only exist if organizations relying on the credentials issued by a given organization have the necessary level of assurance that the reliability of the issuing organization has been established through a formal authorization process.

3.4.1 Examples of Sub-Capabilities (from HWAM)... 3.4.1 Examples of Sub-Capabilities (from HWAM) As described in Table 4: Tracing the HWAM Capability to Blocking Attack Steps, HWAM provides a high-level ability to block or delay attack steps related to the exploitation of hardware devices.

3.4.1 Password Authentication... 3.4.1 Password Authentication There are two kinds of password authentication mechanisms in SSH: basic password authentication and keyboard-interactive authentication.

This rule establishes requirements for the conduct of assessments, as well as the requirements for handling of disputes, to include an appeals process. In the roles established by this rule, C3PAOs and the CMMC AB execute program requirements as codified in the 32 CFR part 170 CMMC Program rule, with appropriate DoD oversight. For ISO/IEC 17020:2012(E) and ISO/IEC 17011:2017(E) compliance, an appeals process is required. Appeals are addressed in §§ 170.8(b)(16) and 170.9(b)(9), (14), (20), and (21). The DoD declines to update the rule content of § 170.6 to include a new subsection on DoD PMs and requesting activities and their responsibilities regarding marking CUI as that subject matter is already addressed for the DoD. DoD Instruction 5200.48 on CUI establishes policy, assigns responsibilities, and prescribes procedures for CUI throughout the DoD in accordance with 32 CFR part 2002, CFR for CUI to include 32 CFR 2002.20 Marking CUI; and 48 CFR 252.204-7008 and DFARS clause 252.204-7012. The CMMC Program requirements make no change to existing policies for information security implemented by the DoD. The DoD declined to modify the rule to further define the existing CMMC PMO oversight responsibilities, identified in § 170.6, which includes the CMMC AB and all other aspects of the program. b. CMMC-AB Comment: There were multiple comments regarding the CMMC Accreditation Body (AB). Ten comments were not relevant to the rule text. Multiple commenters asked about mechanisms to monitor the CMMC AB and how the DoD provides oversight. Seven comments provided valuable editorial recommendations that (printed page 83120) enhanced the existing rule text. Seven comments also raised concerns and asked for clarification about certification of the CMMC AB, its standing with international accreditation bodies and the effects of that standing on the C3PAOs. Two comments sought clarity on the CMMC AB's responsibilities and what resources they will provide to the CMMC ecosystem. One comment suggested incorporation by reference of specific CMMC AB generated artifacts. One comment requested clarity on terms and definitions regarding the CMMC AB. Response: Some comments received lacked relevance to the rule's content, including the establishment of outside entities. The DoD declines to respond to speculative or editorial comments about private citizens or entities, which are outside the scope of this rule. The DoD declines to respond to requests for documents related to the CMMC AB and the CAICO that lack relevance to the CMMC rule.

Information at rest refers to the state of information when it is not in process or in transit and is located on storage devices as specific components of systems. The focus of protection at rest is not on the type of storage device or the frequency of access but rather the state of the information. Organizations can use different mechanisms to achieve confidentiality protections, including the use of cryptographic mechanisms and file share scanning. Organizations may also use other controls including secure off-line storage in lieu of online storage when adequate protection of information at rest cannot otherwise be achieved or continuous monitoring to identify malicious code at rest. FURTHER DISCUSSION CUI at rest means information that is not moving through the network; typically this means data currently stored on hard drives, media, and mobile devices. Implement the necessary security controls to protect the confidentiality of CUI at rest. Although an approved 217 NIST SP 800-171A, pp. 59-60. 218 NIST SP 800-171 Rev. 2, p. 40.

), as amended by section 812 of National Defense Authorization Act for Fiscal Year 2017, which requires DoD to establish a data collection system to provide certain management information with regard to each purchase of services by a military department or defense agency that exceeds \$3 million for services in the following service acquisition portfolio groups: logistics management services, equipment-related services, knowledge-based services, and electronics and communications services. The basic DFARS clause 252.204-7023, Reporting Requirements for Contracted Services, and its alternate I require a contractor to report annually, in the System for Award Management, on the services performed under the contract or order, during the preceding Government fiscal year.

Specifically, the contractor is required to report the following: the total dollar amount invoiced for services performed during the preceding fiscal year; and the number of direct labor hours, including subcontractor hours (when applicable), expended on services performed during the previous Government fiscal year. This information collection will provide DoD with the ability to identify and report annually to Congress, in accordance with 10 U.S.C. 4505, on the inventory of contractor service contract actions. As an adjunct, the information will support DoD's total force management and in making strategic workforce planning and budget decisions pursuant to 10 U.S.C. 129a. DoD Clearance Officer: Mr. Tucker Lucas. Requests for copies of the information collection proposal should be sent to Mr. Lucas at whs.mc- (printed page 53594) alex.esd.mbx.dd-dod-information-collections@mail.mil. Jennifer D. Johnson, Editor/Publisher, Defense Acquisition Regulations System. [FR Doc. 2024-14088 Filed 6-26-24; 8:45 am] BILLING CODE 6001-FR-P

) From subsection (e)(1) because it is not always possible for NGA or other agencies to know in advance what information is both relevant and necessary for it to complete an identity comparison between individuals and a known or suspected terrorist. In addition, because NGA and other agencies may not always know what information about an encounter with a known or suspected terrorist will be relevant to law enforcement for the purpose of conducting an operational response. (5) From subsection (e)(2) because application of this provision could present a serious impediment to counterterrorism, law enforcement, or intelligence efforts in that it would put the subject of an investigation, study or analysis on notice of that fact, thereby permitting the subject to engage in conduct designed to frustrate or impede (printed page 14783) that activity. The nature of counterterrorism, law enforcement, or intelligence investigations is such that vital information about an individual frequently can be obtained only from other persons who are familiar with such individual and his/her activities. In such investigations, it is not feasible to rely upon information furnished by the individual concerning his own activities. (6) From subsection (e)(3), to the extent that this subsection is interpreted to require NGA to provide notice to an individual if NGA or another agency receives or collects information about that individual during an investigation or from a third party. Should the subsection be so interpreted, exemption from this provision is necessary to avoid impeding counterterrorism, law enforcement, or intelligence efforts by putting the subject of an investigation, study or analysis on notice of that fact, thereby permitting the subject to engage in conduct intended to frustrate or impede that activity. (7) From subsections (e)(4)(G) and (H) and (I) (Agency Requirements) and (f) (Agency Rules), because this system is exempt from the access provisions of 5 U.S.C. 552a(d). (8

). Finally, it should be noted that the Department provides established administrative due process to record subjects prior to final adverse determinations with respect to a denial or revocation for eligibility to access classified information or eligibility to occupy a national security position. Regulatory Procedures Executive Order 12866, 'Regulatory Planning and Review' and Executive Order 13563, 'Improving Regulation and Regulatory Review' Executive Orders 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distribute impacts, and equity). Executive Order 13563 also emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This rule is not a significant regulatory action under E.O. 12866. Executive Order 13771, 'Reducing Regulation and Controlling Regulatory Costs' This final rule is an E.O. 13771 deregulatory action. Details on the estimated cost savings of this rule are discussed in the 'expected cost savings' section of the preamble. 2 U.S.C. Ch. 25, 'Unfunded Mandates Reform Act' This final rule is not subject to the Unfunded Mandates Reform Act (UMRA) (2 U.S.C. 1532) because it does not contain a federal mandate that may result in the expenditure by state, local, and tribal governments, in the aggregate, or by the private sector, of \$100M or more in any one year. Public Law 96-354, 'Regulatory Flexibility Act' (5 U.S.C. Ch. 6) It has been certified that 32 CFR part 310 is not subject to the Regulatory Flexibility Act (5 U.S.C. 601), because it would not have a significant economic impact on a substantial number of small entities. The rule primarily implements the procedures for requesting access to and amendment of records covered by the Privacy Act and maintained by the Department of Defense. Public Law 96-511, 'Paperwork Reduction Act' (44 U.S.C. Chapter 35) It has been certified that 32 CFR part 310 does not impose reporting or recordkeeping requirements under the Paperwork Reduction Act of 1995. Executive Order 13132, 'Federalism' Executive Order 13132 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct requirement costs on State and local

governments, preempts State law, or otherwise has Federalism implications. This final rule will not have a substantial effect on State and local governments. List of Subjects in 32 CFR Part 310 Privacy Privacy Act Records maintained on individuals Accordingly, 32 CFR part 310 is revised to read as follows: PART 310·PROTECTION OF PRIVACY AND ACCESS TO AND AMEUREMENT OF INDIVIDUAL RECORDS UNDER THE PRIVACY ACT OF 1974 Subpart A·General Provisions 310.1 Purpose. 310.2 Definitions. (printed page 14731)

. This implementation specification would require a regulated entity to have in place technical controls that distinguish between users and technology assets, that are permitted to access the regulated entity's relevant electronic information systems and those that are not permitted to do so and would require that the controls permit or disallow access accordingly. Properly deployed network-based solutions can limit the ability of a hacker to gain access to an organization's network or impede the ability of a hacker already in the network from accessing other electronic information systems-especially systems containing sensitive data. [716] Access controls could include role-based access, user-based access, or any other access control mechanisms the organization deems appropriate. [717] Access controls need not be limited to computer systems-firewalls, network segmentation, and network access control solutions are effective means of limiting access to relevant electronic information systems. [718] Additionally, we propose to add an implementation specification for maintenance at proposed 45 CFR 164.312(a)(2)(viii) . Under this proposal, a regulated entity would be expressly required to review and test the effectiveness of the procedures and technical controls required by the implementation specifications associated with the standard for access control at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. c. Section 164.312(b)(1)-Standard: Encryption and Decryption Encryption can reduce the risks and costs of unauthorized access to ePHI. [719] For example, if a hacker gains access to unsecured ePHI on a network server or if a device containing unsecured ePHI is stolen, a breach of PHI will be presumed and reportable under the Breach Notification Rule. [720] The Breach Notification Rule applies to unsecured PHI, which is PHI that is not rendered unusable, unreadable, or indecipherable to unauthorized persons through the use of a technology or methodology specified by the Secretary in guidance issued under the HITECH Act. [721] The Department's guidance on rendering unsecured PHI unusable, unreadable, or indecipherable to persons who are not authorized to access such PHI states that ePHI at rest (i.e., stored in an information system or electronic media) is considered secured if it is encrypted in a manner consistent with NIST Special Publication 800-111 [722] (-SP 800-111-). The ePHI encrypted in a manner consistent with SP 800-111 is not considered unsecured PHI and therefore qualifies for what is commonly known as the Breach Notification safe harbor, meaning that it is not subject to the requirements of the Breach Notification Rule. [723] Thus, by encrypting ePHI in a manner consistent with the Secretary's guidance, a regulated entity may not only fulfill its encryption obligation under the Security Rule, but also make use of the (printed page 968)

This method is often used when a foreign interest does not own voting interests sufficient to elect, or otherwise is not entitled to representation on the company's governing board. In such circumstances, the effects of foreign ownership will generally be mitigated by a resolution of the board of directors stating the company recognizes the elements of FOCI and acknowledges its continuing obligations under DD Form 441, ·DoD Security Agreement· (available at <http://www.dtic.mil/whs/directives/infomgt/forms/eforms/dd0441.pdf>). The resolution will identify the foreign shareholders and their representatives (if any) and note the extent of foreign ownership. The resolution will also include a certification that the foreign shareholders and their representatives will not require, will not have, and can be effectively excluded from access to all classified information in the possession of the contractor, and will not be permitted to occupy positions that may enable them to influence the organization's policies and practices in the performance of classified contracts. Copies of such resolutions will be furnished to all board members and principal management officials. (B) SCA. The SCA is a tailored FOCI mitigation agreement often used when a foreign interest does not effectively own or control a company or corporate family (i.e., the company or corporate family are under U.S. control), but the foreign interest is entitled to representation on the company's board. When an SCA is implemented, a U.S. citizen serves as an outside director, as defined in DoD 5220.22-M. DSS may determine the need for more than one outside director based on the FOCI analysis and risk assessments. (C) SSA. The SSA is a tailored FOCI mitigation agreement that preserves the foreign owner's right to be represented on the company's board (inside directors) with a direct voice in the business management of the

company while denying the foreign owner unauthorized access to classified information. An SSA is based on the analysis of the FOCI factors set forth in paragraph (b)(3) and is often used when a foreign interest effectively owns or controls a company or corporate family. DSS assesses the implications of the FOCI factors in accordance with paragraphs (b)(3) and (b)(4)(iii) of this section. U.S. citizens serve as outside directors in accordance with DoD 5220.22-M. (1) If a GCA requires a contractor cleared under an SSA to have access to proscribed information, the GCA will initiate action to consider a NID at the pre-contract phase to confirm that disclosure of such information is consistent with the national security interests of the United States. (2) Proscribed information includes TS; COMSEC material, excluding controlled cryptographic items when unkeyed and utilized with unclassified keys; RD; SAP; and SCI. (3

DFARS 252.204-7021 (Cybersecurity Maturity Model Certification Requirements) Requires CMMC certification at the level specified in the contract, effective Phase 1 November 10, 2025. Contractors should review the full text of DFARS 252.204-7021 in conjunction with their contracting officer and legal counsel to ensure full compliance. The clause should be read alongside the CMMC requirements at 32 CFR Part 170.

to address the use of performance-based payments. The primary objective of this rule is to remove the restrictions at DFARS 232.1001(a) and the clauses at 252.232-7012(b)(i) and 252.232-7013(b)(i) that limit performance-based payments to amounts not greater than costs incurred up to the time of payment, as required 10 U.S.C. 2307 . There were no significant issues raised by the public comments in response to the initial regulatory flexibility analysis. This rule will apply to approximately 55 small entities per year that are awarded contracts that provide performance-based contract payments from DoD. This rule adds a reporting requirement that will require an entry in the annual representations and certifications with regard to whether the offeror's financial statements are in compliance with Generally Accepted Accounting Principles. DoD estimates that the skill necessary for this requirement is at the journeyman level and that each entry will require an average of 6 minutes. This rule will not have a significant economic impact on small entities. There are no significant alternatives consistent with the stated objectives of the statute. VIII. Paperwork Reduction Act This rule affects the information collection requirements at DFARS subpart 232.10 (and associated clauses at DFARS 252.232-7012 and 252.232-7013, currently approved under OMB Control Number 0704-0359, DFARS Part 232, Contract Financing. The impact, however, is negligible, because only the last three lines of the table are deleted, which do not impose the predominance of the burden. This rule also adds a new information collection requirement that has been approved by the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). This information collection requirement has been assigned OMB Control Number 0750-0001, entitled ·Defense Federal Acquisition Regulation Supplement (DFARS), Performance-Based Payments·Representation·. List of Subjects in 48 CFR Parts 202 , 204 , 212 , 232 , and 252 Government procurement Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. Therefore, 48 CFR parts 202 , 204 , 212 , 232 , and 252 are amended as follows: 1. The authority citation for 48 CFR parts 202 , 204 , 212 , 232 , and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 . PART 202·DEFINITIONS OF WORDS AND TERMS 2. Amend section 202.101 by adding in alphabetical order a definition for ·Nontraditional defense contractor· to read as follows: 202.101 Definitions. * * * * * Nontraditional defense contractor means an entity that is not currently performing and has not performed any contract or subcontract for DoD that is subject to full coverage under the cost accounting standards prescribed pursuant to 41 U.S.C. 1502 and the regulations implementing such section, for at least the 1-year period preceding the solicitation of sources by DoD for the procurement (10 U.S.C. 2302(9)). * * * * * PART 204·ADMINISTRATIVE AND INFORMATION MATTERS 3. Amend section 204.1202 by· a.

), which prohibits agencies from procuring or obtaining, renewing a contract to procure or obtain, or using an IoT device if the agency's Chief Information Officer determines in certain situations that the use of such a device prevents compliance with NIST SP 800-213. The rule advises contracting officers at 39.X03-1(b) of the prohibition and how the prohibition may be waived by the head of the agency if certain criteria are met. B. FIS Using Cloud Computing Services When acquiring services to develop, implement, operate, or maintain a FIS (printed page 68405) using cloud computing services, agencies will identify the FIPS Publication 199 impact level and the corresponding Federal Risk and Authorization Management Program (FedRAMP) authorization level for all applicable cloud computing services in the contract. Safeguards, controls, and maintenance of certain systems within

the United States. Paragraph (c) of the clause 52.239-XX requires contractors to implement and maintain the security and privacy safeguards and controls in accordance with the FedRAMP level specified by the agency, engage in continuous monitoring activities, and provide continuous monitoring deliverables as required for FedRAMP approved capabilities. More information on these deliverables can be found in the "FedRAMP Continuous Monitoring Strategy Guide" at https://www.fedramp.gov/assets/resources/documents/CSP_Continuous_Monitoring_Strategy_Guide.pdf. Additionally, paragraph (c) specifies that, when a system is categorized as having FIPS Publication 199 high impact, contractors must maintain within the United States or its outlying areas (see FAR 2.101) all Government data that is not physically located on U.S. Government premises, unless otherwise specified in the contract. Government data. Paragraph (f) of the clause 52.239-XX requires contractors to provide and dispose of Government data and Government-related data in the manner and format specified in the contract. Contractors must also provide confirmation to the contracting officer that such data has been disposed of in accordance with contract closeout procedures. Other protections.

) If the USG agency does not approve the disclosure of the information related to the proposed classified visit, it will deny the classified visit request. The USG agency will advise the requesting government and the contractor to be visited of the reason for the denial. (2) The contractor may accept the visitor(s), but only information that is in the public domain may be disclosed during the classified visit. (C) Non-sponsorship. The USG agency will decline to render a decision on a classified visit request that is not in support of a USG program. The USG agency will furnish a declination notice indicating that the classified visit is not USG-approved (i.e., the classified visit is non-sponsored) to the requesting foreign government with an information copy to the U.S. contractor to be visited. (1) A declination notice does not preclude the classified visit, provided the contractor has, or obtains, an export authorization for the information involved and, has been notified that the requesting foreign government has provided the required security assurance of the proposed visitor to the USG agency in the original classified visit request. (2) It is the contractor's responsibility to consult applicable export regulations to determine licensing requirements regarding the disclosure of export-controlled information during such classified visits by foreign nationals. (D) Visits to subsidiaries. A classified visit request authorization for a classified visit to any element of a corporate family may be used for visits to other divisions or subsidiaries within the same corporate family in accordance with § 117.15(h)(3), provided disclosures are for the same purpose and the information to be disclosed does not exceed the parameters of the approved classified visit request. (E) Long-term classified visits and assignments of foreign nationals. Extended classified visits and assignments of foreign nationals to contractor locations can be authorized only when it is essential pursuant to a contract or government agreement (e.g., joint venture, liaison representative to a joint or multinational program, and direct commercial sale). The contractor will: (1) Consult with its empowered official for guidance. (2) Notify the CSA in advance of all long-term classified visits and assignments of foreign nationals. (3) Provide the CSA with a copy of the approved classified visit authorization or the USG export authorization. (4) Control of foreign visitors to U.S. contractors. (i) Contractor. The contractor will: (A) Establish procedures to ensure that foreign visitors are not afforded access to classified information except as authorized by an export license, approved visit request, or other exemption to the licensing requirements. (B) Not inform the foreign visitor of the scope of access authorized or of the limitations imposed by the government. (ii) Foreign visitors.

Privacy requesters are a diverse community, including lawyers, industry professionals, reporters, and members of the public. Costs for these requestors can include the time required to research the current Privacy rule for each component and the time and preparation required to submit a request/appeal. DoD Privacy subject matter experts estimate that 40% of Privacy requests to DoD may involve consultation of the Code of Federal Regulations and the department's several privacy regulations. DoD estimates the consolidation to one privacy regulation will save those referring to the CFR for Privacy guidance approximately 30 minutes of research, review, and compliance time. For purposes of estimating opportunity costs, DoD subject matter experts deemed it reasonable to use the average of a lawyer's/judicial law clerk's mean hourly wage (\$66.44/hour), as informed by the Bureau of Labor and Statistics, and the 2016 federal minimum wage (\$9/hour) to approximate an hourly wage for an average requester. That rate is \$37.72/hour. Through this consolidation, DoD expects to save the requester community at least \$63,686 annually, as reflected in the chart below using FY 2016 data (annualized costs over perpetuity at a 7 percent discount rate is \$63,686; present value costs

is -\$909,800). The cost savings anticipated by the repeal of the DoD Component rules are accounted for in this rulemaking and will not be separately noted in the individual repeal actions. (printed page 14729) Rule Component # 2016 access & amdmnt requests × 40% of privacy requests × Time per request (minutes) × Hourly wage of requester = Projected cost savings to public 311 OSD/JS 2,530 × 40 × 30 × \$37.72 = \$19,086.32 312 DoDIG 196 × 40 × 30 × 37.72 = 1,478.62 313 CJCS/JS 0 × 40 × 30 × 37.72 = 0.00 314 DARPA 0 × 40 × 30 × 37.72 = 0.00 315 USUHS 0 × 40 × 30 × 37.72 = 0.00 316 DISA 65 × 40 × 30 × 37.72 = 490.36 317 DCAA 10 × 40 × 30 × 37.72 = 75.44 318 DTRA 9 × 40 × 30 × 37.72 = 67.90 319 DIA 99 × 40 × 30 × 37.72 = 746.86 320 NSA/CSA 206 × 40 × 30 × 37.72 = 1,554.06 323 DLA 431 × 40 × 30 × 37.72 = 3,251.46 324 DFAS 261 × 40 × 30 × 37.72 = 1,968.98 326 NRO 18 × 40 × 30 × 37.72 = 135.79 327 DeCA 16 × 40 × 30 × 37.72 = 120.70 329 NGB 126 × 40 × 30 × 37.72 = 950.54 505 Army 2834 × 40 × 30 × 37.72 = 21,379.70 701 DON 1055 × 40 × 30 × 37.72 = 7,958.92 806b AF 541 × 40 × 30 × 37.72 = 4,081.30 Total 63,686.45 Changes Made in the DOD Privacy Program Final Rule After publishing the proposed rule, 'Department of Defense Privacy Program,' on September 13, 2018 (83 FR 46542), DoD published on October 17, 2018 a new system of records notice for the Personnel Vetting Records System, DUSDI 02-DoD (83 FR 52420), and a corresponding interim final rule (83 FR 52317

As stated by the Health Care Industry Cybersecurity Task Force in its 2017 report on the state of cybersecurity in health care: 'The health care system cannot deliver effective and safe care without deeper digital connectivity. If the health care system is connected, but insecure, this connectivity could betray patient safety, subjecting them to unnecessary risk and forcing them to pay unaffordable personal costs.' [137] In the event of a cybersecurity incident, patients' health, including their lives, may be at risk where such incident creates impediments to the provision of health care, such as interference with the operations of a critical medical device, or to the administrative or clinical operations of a regulated entity, such as preventing the scheduling of appointments or viewing of an individual's health history. [138] According to a Cybersecurity & Infrastructure Security Agency (CISA) statistical analysis of the effects of a hypothetical cyberattack on a model hospital, a hospital's relative performance will suffer amidst a cyberattack. [139] The analysis found that the hypothetical cyberattack would lead to hospital strain from inaccessible patient schedules and records, disrupted communication, and delays in processing and communicating test results in time to effectively treat individuals. [140] While the analysis did not find any deaths directly attributable to the hypothetical attack, it is logical to conclude that deaths or at least worsened outcomes are a significant risk where there are disruptions in communications, as well as delays in processing and communicating test results, especially for emergent or acute medical cases. For example, an inability to access an individual's pharmacy records could affect the ability of a pharmacist to identify known interactions between newly prescribed medications and an existing medication list, potentially leading to an individual's injury or death. Other studies have similarly found that cyberattacks can have a substantial effect on access to health care, and potentially mortality. [141] In fact, a more recent study found that cyberattacks had disproportionately negative effects on in-hospital mortality rates for Black patients who were already admitted to the hospital at the time of the cyberattack. [142] A recent survey found that 92 percent of surveyed health care organizations had experienced a cyberattack in the past year [143] and almost three-quarters of the respondents who had experienced a cyberattack reported negative effects on patient care, including delays in tests or procedures, longer stays, and increased mortality rates complications from medical procedures, and patient transfers or diversions to other facilities. [144] A recent letter from NCVHS referenced anecdotal accounts of patient deaths that have been attributed to ransomware attacks. [145]

Commingleing of RD, FRD, and TFNI with NSI in the same document should be avoided to the greatest degree possible. When mixing this information cannot be avoided, the marking requirements in 10 CFR part 1045 , section 140(f) and declassification requirements of 10 CFR part 1045 , section 155 apply. (10) Protection of RD and FRD. Most of the protection requirements for RD and FRD are similar to NSI and are based on the classification level. However, there are some protection requirements for certain RD information that may be applied through specific contract requirements by the GCA. These range from distribution limitations through the limitation of access to specifically authorized individuals to specific storage requirements, including the requirement for

IDSS, and additional accountability records. (i) Any DOE contractor that violates a classified information security requirement may be subject to a civil penalty under the provisions of 10 CFR part 824. (ii) Certification is required for individuals authorized access to specific Sigma categories, as appropriate. Address questions regarding these requirements to DOE's National Nuclear Security Administration, Office of Defense Programs. (iii) Storage and distribution requirements are determined by the classification level, category, and Sigma category. Sigma designation is not a requirement for all RD documents. Storage and distribution requirements will be dependent only on classification level and category. (11) Accountability. In addition to TOP SECRET information, some SECRET RD information is considered accountable (e.g., specific Sigma 14 matter). Each nuclear weapon data control point will keep a record of transactions involving Secret nuclear weapon data documents under its jurisdiction including origination, receipt, transmission, current custodian, reproduction, change of classification, declassification, and destruction. (12) Cybersecurity. Classified databases, systems, and networks containing RD and FRD are protected under the requirements developed and distributed by the DOE Office of the Chief Information Officer. (f) NNPI. NNPI is information associated with the Naval Nuclear Propulsion Program and is governed by Office of the Chief of Naval Operations (printed page 83363) Instruction (OPNAVINST) N9210.3, 'Safeguarding of Naval Nuclear Propulsion Information' (available at: [https://www.secnav.navy.mil/doni/Directives/09000%20General%20Ship%20Design%20and%20Support/09-200%20Propulsion%20Plants%20Support/N9210.3%20\(Unclas%20Portion\).pdf](https://www.secnav.navy.mil/doni/Directives/09000%20General%20Ship%20Design%20and%20Support/09-200%20Propulsion%20Plants%20Support/N9210.3%20(Unclas%20Portion).pdf)). Naval Reactors, a joint DOE/Department of Navy organization established under 50 U.S.C. 2406 and 2511

<https://www.hhs.gov/sites/default/files/ocr/privacy/hipaa/administrative/securityrule/techsafeguards.pdf?language=es>. Back to Citation 344. The Department previously acknowledged that information transmitted by a telephone voice response system in response to a telephone request, and some voice technology digitally produced from an information system and transmitted by telephone are both covered by this definition. See 68 FR 8334, 8342 (Feb. 20, 2003); 75 FR 40868, 40874 (July 14, 2010); and 78 FR 5566, 5575 (Jan. 25, 2013). Back to Citation 345. 78 FR 5566, 5575-5576 (Jan. 25, 2013). Back to Citation 346. 45 CFR 164.304 (definition of 'Access'). Back to Citation 347. 45 CFR 164.304 (definition of 'User'). Back to Citation 348. 45 CFR 164.304 (definition of 'Security incident'). Back to Citation 349. 45 CFR 164.308(a)(3)(i); proposed 45 CFR 164.308(a)(9)(i). Back to Citation 350. 45 CFR 164.304 (definition of 'Administrative safeguards'). Back to Citation 351. 45 CFR 164.304 (definitions of 'Administrative safeguards', 'Physical safeguards', and 'Technical safeguards'). Back to Citation 352. See also Special Publication 800-82r3, Guide to Operational Technology Security, National Institute of Standards and Technology, section 6.2.1, p. 97, Identity Management and Access Control (PR.AC) (discussing the need of organizations to apply authentication controls for users, devices, and processes within the technology environment) (September 2023). Back to Citation 353. While the Department also regulates adoption and meaningful use of certified EHR technology, such as the actions of the end-user with respect to having and meaningfully using certified health IT to meet certain requirements, such as those requirements for the Promoting Interoperability performance category of the Merit-based Incentive Payment System (MIPS) (sections 1848(q)(2)(B)(iv) and 1848(o)(2) of the SSA), the definitions proposed in this NPRM would apply only to regulated entities' compliance with the Security Rule. Back to Citation 354. University of Texas M.D. Anderson Cancer Center, *supra* note 258, p. 478. Back to Citation 355. *Id.* Back to Citation 356. See proposed 45 CFR 164.308(b)(1)(i) and (ii) and (b)(2)(ii). Back to Citation 357. See proposed 45 CFR 164.312(a)(1). Back to Citation 358. See proposed 45 CFR 164.312(a)(2)(iv). Back to Citation 359. See 45 CFR 164.310(a)(1). Back to Citation 360. See 45 CFR 164.312(a)(1). Back to Citation 361. 45 CFR 164.304 (definition of 'Physical safeguards'). Back to Citation 362. See NIST definition of 'malware', Glossary, Computer Security Resource Center, National Institute for Standards and Technology, U.S. Department of Commerce, <https://csrc.nist.gov/glossary/term/malware>. Back to Citation 363. 'Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients', *supra* note 16. Back to Citation 364. *Id.* at 15. Back to Citation 365. *Id.* Back to Citation 366. 'Cybersecurity Performance Goals', *supra* note 18. Back to Citation 367. *Id.*

(c) NIST SP 800-37, titled 'Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy', Revision 2 (NIST SP 800-37 R2), describes the Risk Management Framework (RMF) and provides guidelines for applying the RMF to information systems and organizations. The RMF provides a disciplined, structured, and flexible process for managing

security and privacy risk that includes information security categorization; control selection, implementation, and assessment; system and common control authorizations; and continuous monitoring. The RMF includes activities to prepare organizations to execute the framework at appropriate risk management levels. The RMF also promotes near real-time risk management and ongoing information system and common control authorization through the implementation of continuous monitoring processes; provides senior leaders and executives with the necessary information to make efficient, cost-effective, risk management decisions about the systems supporting their missions and business functions; and incorporates security and privacy into the system development life cycle. Executing the RMF tasks links essential risk management processes at the system level to risk management processes at the organization level. In addition, it establishes responsibility and accountability for the controls implemented within an organization's information systems and inherited by those systems. This document is incorporated by reference as a source for definitions. (d) NIST SP 800-39, titled "Managing Information Security Risk: Organization, Mission, and Information System View," March 2011 (NIST SP 800-39 Mar2011), provides guidance for an integrated, organization-wide program for managing information security risk to organizational operations (i.e., mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation resulting from the operation and use of Federal information systems. NIST SP 800-39 Mar2011 provides a structured, yet flexible approach for managing risk that is intentionally broad-based, with the specific details of assessing, responding to, and monitoring risk on an ongoing basis provided by other supporting NIST security standards and guidelines. The guidance provided in this publication is not intended to replace or subsume other risk-related activities, programs, processes, or approaches that organizations have implemented or intend to implement addressing areas of risk management covered by other legislation, directives, policies, programmatic initiatives, or mission/business requirements. Rather, the risk management guidance described herein is complementary to and should be used as part of a more comprehensive Enterprise Risk Management (ERM) program. This document is incorporated by reference as a source for definitions.

3.7.1 Global | 3. 3.7.1 Global by Data Base ; In this scheme, each data base is assigned a classification equal to that of the most sensitive data it contains.

(Comment 45) Several comments state that, although retailers will not be required to keep track of foods sold to consumers, retailers will be required to keep records on those immediate subsequent recipients who are wholesalers or other retailers. The comments add that, unless the recordkeeping exclusion applies to all foods that are sold from the store, it is essentially meaningless. Food retailers do not know whether a person who comes into a store and buys food will be using the food for personal consumption or for a business purpose. To cover the possibility that a purchase was intended for business purposes would essentially require a retailer to record all consumer transactions. The comments state that this would not increase food security or consumer confidence. The comments also state that the trust of consumers is of tantamount importance and requiring documentation of all consumer transactions will diminish that trust without furthering the goal of food security. (Response) Although retailers must keep records of immediate subsequent recipients of food who are not consumers, retailers are not required to do so unless that information is reasonably available, for example, when the purchaser has an existing commercial account. (See response to comment 38 of this document.) Retailers need not ask the status of each purchaser, and retailers will not be required to record every consumer transaction. Under § 1.327(e) of this final rule, persons who operate retail food establishments that distribute food to persons who are not consumers are subject to all of the requirements in subpart J of this final rule. However, the requirements in § 1.345 of this final rule to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients that are not consumers applies as to those transactions only, and only to the extent the information is reasonably available. FDA notes that there is an exclusion with respect to food that is manufactured, processed, packed, held, received, or transported for personal consumption. Such activities are excluded from the rule because if a traceback or trace forward investigation is necessary, FDA can learn from sickened consumers the sources of the food they purchased, or notify consumers generally about food that presents a threat. Whether food is for personal consumption depends on many factors, but FDA would consider food prepared in a private home and transported for other than business purposes to qualify for this exclusion. An example of food covered by this exclusion includes food prepared for "pot luck" suppers.

Section 170.4 includes acronyms and definitions used in the rule text and can be used as a reference

while reading the text and tables. CMMC introduces new terms and associated definitions, and customizes definitions for existing terms, as applied to the CMMC Program. CMMC-custom terms and definitions are clearly marked to distinguish from terms sourced externally. CMMC also utilizes terms created by other authoritative sources, including NIST. Terms from other authoritative sources are also listed in § 170.4 and are properly sourced. The Department developed the following CMMC-custom terms to enhance understanding of the requirements and elements of the CMMC Program and welcomes comments on these definitions as part of the proposed rule: Accreditation Accreditation Body Assessment Self-Assessment CMMC Level 2 Certification Assessment CMMC Level 3 Certification Assessment Assessment Findings Report Assessment Team Asset Categories Authorized CMMC Assessment and Certification Ecosystem CMMC Assessment Scope CMMC Assessor and Instructor Certification Organization (CAICO) CMMC instantiation of eMASS CMMC Level 1 Self-Assessment CMMC Level 2 Conditional Certification Assessment CMMC Level 2 Conditional Self-Assessment CMMC Level 2 Final Certification Assessment CMMC Level 2 Final Self-Assessment CMMC Level 3 Conditional Certification Assessment CMMC Level 3 Final Certification Assessment CMMC Third-Party Assessment Organization (C3PAO) Contractor Risk Managed Assets Controlled Unclassified Information (CUI) Assets External Service Provider (ESP) Federal Contract Information (FCI) Assets Organization-Defined Organization Seeking Assessment (OSA) Organization Seeking Certification (OSC) Out-of-Scope Assets Periodically Process, store, or transmit Restricted Information Systems Security Protection Assets Specialized Assets Test Equipment. Section 170.5-Policy Section 170.5 addresses the policy underlying the rule. The protection of FCI and CUI on defense contractor information systems is crucial to the continuity of the missions and functions of the DoD. To that end, this rule requires that contractors and subcontractors implement the specified security requirements for the applicable CMMC Level. For CMMC Level 3, safeguards defined in NIST SP 800-172 and DoD-specified parameters (see table 1 to § 170.14(c)(4)) may be required. Program Managers and requiring activities identify the applicable CMMC Level. Factors used to determine which CMMC Level will be applied are included but not limited to the list found in § 170.5(b)(1-5). CMMC Program requirements will flow down to subcontractors, as applicable (see § 170.23). A DoD Service Acquisition Executive or a Component Acquisition Executive may elect to waive inclusion of CMMC Program requirements in a solicitation or contract.

- NIST continued the Journey to Cybersecurity Framework (CSF) 2.0 by releasing a CSF 2.0 Concept Paper, publishing a discussion draft of the CSF 2.0 Core, and issuing a draft CSF 2.0 with Core Implementation examples. Additionally, NIST published an analysis of comments received on each draft and hosted two hybrid workshops (1 st workshop & 2 nd workshop). - NIST continued to lead and support community engagement on cybersecurity supply chain risk management through the Software and Supply Chain Assurance (SSCA) Forum, support the Federal Acquisition Security Council, and refine supply-chain guidance in SP 800-161 Revision 1, Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations . - NIST issued a working draft of the SP 800-55 Rev. 2, Performance Measurement Guide for Information Security for community discussion and feedback and hosted a cybersecurity measurement workshop on the current state of cybersecurity performance measurement, needs, and path forward. - NIST initiated updates to the Protecting Controlled Unclassified Information (CUI) Series, issued a pre-call for comment, released an initial public draft of SP 800-171r3, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, and hosted a webinar to provide an overview of the draft. - NIST launched the Cybersecurity & Privacy Reference Tool (CPRT) - an online application that provides NIST guidance and frameworks in a consistent format for reference data and allows users to understand the relationships between NIST resources. - NIST continued the development of the Open Security Controls Assessment Language (OSCAL) - a set of eXtensible Markup Language (XML), JavaScript Object Notation (JSON), and Ain't Mark-up Language (YAML) formats that provide machine-readable representations of security and privacy information relative to the implementation, assessment, and continuous monitoring of systems.

It includes, but is not limited to: · configuration data required to operate a security protection asset, Additional Guidance on Level 2 Scoping CMMC Assessment Scope · Level 2 | Version 2.13 6 · log files generated by or ingested by a security protection asset, · data related to the configuration or vulnerability status of in-scope assets, and · passwords that grant access to the in-scope environment. Table 2. Security Protection Asset Examples Asset Type Security Protection Asset Examples People · Consultants who provide cybersecurity service · Managed service provider personnel who implement system maintenance · Enterprise network administrators Technology · Cloud-based security solutions · Hosted Virtual Private Network (VPN) services · SIEM solutions Facilities

· Co-located data centers · Security Operations Centers (SOCs) · OSA office buildings In addition, the OSA is required to: · document each asset in an asset inventory; there is no requirement to embed each asset in the SSP; · document the treatment of these assets in the SSP; and · provide a network diagram of the CMMC Assessment Scope (to include these assets) to facilitate scoping discussions during the pre-assessment. Contractor Risk Managed Assets Contractor Risk Managed Assets are not intended to , but are capable of processing, storing, or transmitting CUI because of the security policy, procedures, and practices in place. Contractor Risk Managed Assets are not required to be physically or logically separated from CUI Assets. Contractor Risk Managed Assets are part of the Level 2 CMMC Assessment Scope. These assets are managed using the OSA's risk-based information security policy, procedures, and practices. Furthermore, the assets must be assessed against CMMC requirements if insufficiently documented in the SSP or if the OSA's risk-based security policies, procedures, and practices documentation or other findings raise questions about these assets . In these cases, the assessor can conduct a limited check to identify deficiencies. In addition, the OSA is required to: · document each asset in an asset inventory; there is no requirement to embed each asset in the SSP; · document the treatment of these assets in the SSP; and

A regulated entity may be able to improve the control and review of the use of administrative access privileges, such as through a privileged access management system, to understand how privileged accounts are used within its environment and help detect and prevent the misuse of privileged accounts. [702] The proposed implementation specification would require a regulated entity to separate the unique user identities required by the implementation specification for unique user identification based on the type of access privileges used by a specific unique user. For example, the adoption of health IT that is certified through the ONC Health IT Certification Program as having the technical capability to establish user permissions for accessing, and performing actions with, electronic health information based on unique identifiers may contribute to a regulated entity's compliance with the proposed new implementation specification for administrative and increased access privileges, should the proposal be finalized. [703] This proposed new implementation specification aligns with the Department's essential CPG for Separate User and Privileged Accounts by addressing the separation of privileged or administrator access rights from common user accounts. [704] Additionally, the Department proposes to redesignate the implementation specification for emergency access procedures at 45 CFR 164.312(a)(2)(ii) as proposed 45 CFR 164.312(a)(2)(iii) and to modify it to require a regulated entity to establish both written procedures and technical procedures for obtaining necessary ePHI during an emergency and to implement them as needed. For example, we note that the adoption of health IT that is certified through the ONC Health IT Certification Program as having the technical capability to permit an identified set of users to access electronic health information during an emergency may contribute to a regulated entity's compliance with the proposed implementation specification for emergency access procedures, should the proposal be finalized. [705] Under the Department's proposal, the implementation specification for automatic logoff at 45 CFR 164.312(a)(2)(iii) would be redesignated as proposed 45 CFR 164.312(a)(2)(iv) and modified to require a regulated entity to deploy technical controls that terminate an electronic session after a period of inactivity. Deploying a mechanism to automatically terminate an electronic session after a period of inactivity reduces the risk of unauthorized access when a user forgets or is unable to terminate their session. [706] Failure to deploy automatic logoff not only increases the risk of unauthorized access and potential alteration or destruction of ePHI; it also impedes an organization's ability to properly investigate such unauthorized access because it would appear to originate from an authorized user. [707]

(t) The Provost Marshal General is authorized to act on all requests for provost marshal activities and law enforcement functions for the Army, all matters relating to police intelligence, physical security, criminal investigations, corrections and internment (to include confinement and correctional programs for U.S. prisoners, criminal investigations, provost marshal activities, and military police support. The Provost Marshal General is responsible for the Office of Security, Force Protection, and Law Enforcement Division and is the functional proponent for AR 190-series (Military Police) and 195-series (Criminal Investigation), AR 630-10 Absent Without Leave, Desertion, and Administration of Personnel Involved in Civilian Court Proceedings, and AR 633-30, Military Sentences to Confinement. (u) The Commander, U.S. Army Criminal Investigation Command, is authorized to act on requests for criminal investigative records of USACIDC headquarters, and its subordinate activities, and military police reports. This includes criminal investigation records, investigation-in-progress records, and all military police records and reports that result in

criminal investigation reports. This authority has been delegated to the Director, U.S. Army Crime Records Center. (v) The Commander, U.S. Army Human Resources Command, is authorized to act on requests for military personnel files relating to active duty personnel including, but not limited to military personnel matters, military education records including records related to the removal or suspension from a military school or class; personnel locator, physical disability determinations, and other military personnel administration records; records relating to military casualty and memorialization activities; heraldic activities, voting, records relating to identification cards, naturalization and citizenship, commercial solicitation, Military Postal Service Agency and Army postal and unofficial mail service. The Commander, U.S. Army Human Resources Command, is also authorized to act on requests concerning all personnel and medical records of retired, separated, discharged, deceased, and reserve component military personnel, unless such records clearly fall within another Denial Authority's authority. (w) The Commander, U.S. Army Resources Command-St. Louis has been delegated authority to act on behalf of the U.S. Army Human Resources Commander for requests concerning all personnel and medical records of retired, separated, discharged, deceased, and reserve component military personnel, unless such records clearly fall within another Denial Authority's authority. The authority does not include records relating to USAR plans, policies, and operations; changes in the organizational status of USAR units, mobilization and demobilization policies; active duty tours, and the individual mobilization augmentation program.

The primary purpose of the DIB CS/IA program is to share cyber security information to promote more effective cyber security, not only for the DIB, but also for the DoD and U.S. Government. The program contains numerous information handling and sharing restrictions, applicable to both the Government and DIB participants, to safeguard against any unauthorized collection, use, or dissemination of such information. However, the program does not limit the Government's ability to conduct lawful activities, including law enforcement, counterintelligence activities, or other activities in the interest of U.S. national security (§ 236.6(d)). No change is made to the rule.

Comment: One comment recommended that the rule incorporate privacy protections of the National Cyber Security Division's Joint Cybersecurity Services Pilot (JCSP). Response: The detailed processes summarized in the PIA for the DIB CS/IA program are comprehensive and ensure appropriate safeguards for PII provided by DIB participants in a similar manner as described in the PIA prepared for the Department of Homeland Security's JCSP. No change is made to the rule. Comment: One comment stated the interim rule should be amended to impose fines on private companies that intentionally or negligently disclose excessive PII. Response: It is not clear what the commenter meant by the term "excessive PII." As discussed above, the DIB CS/IA program only receives PII in two ways: (i) For program administration and management purposes; and (ii) for cyber incident response and analysis purposes. In both cases, DIB companies share information only when it is relevant for those authorized purposes. In addition, DIB companies are prohibited from sharing any information, including PII, unless they have determined that it has been lawfully collected and is authorized to be shared with the Government. If it were to appear that a company is reporting excessive information not relevant to the program, the Government would seek to work with the company to clarify the sharing guidelines and support the company's efforts to refine its processes to implement more effective limits on sharing unnecessary information. If, despite these efforts, a company continued to share information that the Government deemed inappropriate within the scope of the program, the Government would take appropriate actions on a case by case basis, including potentially terminating the information sharing relationship with that participant. This is a voluntary program and fines are not part of the program. No change is made to the rule. Comment: Two comments recommended changes to the definitions of cyber incident, compromise and threat. Response: The rule leverages established definitions to the maximum extent possible. The source for the definition of "compromise", "cyber incident" and "threat" are from the Committee on National Security Systems Instruction No. 4009, "National Information Assurance Glossary," (

108 If a comparable report meets the requirements of what is to be included in an assessment report (e.g., a report generated from a security or privacy management and reporting tool), then the comparable report would constitute the assessment report. NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

the organization updates security and privacy plans, security and privacy assessment reports, and plans of action and milestones on an on going basis. Updates to the plans reflect modifications to controls based on risk mitigation activities carried out by system owners or common control providers. Updates to control assessment reports reflect additional assessment activities carried out to determine control effectiveness based on implementation details in the plans. Plans of action and milestones are updated based on progress made on the current outstanding items; address security and privacy risks discovered as part of control effectiveness monitoring; and describe how the system owner or common control provider intends to address those risks. The updated information raises awareness of the security and privacy posture of the system and the common controls inherited by the system, thereby, supporting near real-time risk management and the ongoing authorization process. The frequency of updates to risk management information is at the discretion of the system owner, common control provider, and authorizing officials in accordance with federal and organizational policies and is consistent with the organizational and system-level continuous monitoring strategies. The updates to information regarding the security and privacy posture of the system and the common controls inherited by the system are accurate and timely since the information provided influences ongoing actions and decisions by authorizing officials and other senior leaders within the organization. The use of automated support tools and organization-wide security and privacy program management practices ensure that authorizing officials can readily access the current security and privacy posture of the system. Ready access to the current security and privacy posture supports continuous monitoring and ongoing authorization and promotes the near real-time management of risk to organizational operations and assets, individuals, other organizations, and the Nation. Organizations ensure that information needed for oversight, management, and auditing purposes is not modified or destroyed when updating security and privacy plans, assessment reports, and plans of action and milestones. Providing an effective method to track changes to systems through configuration management procedures is necessary to achieve transparency and traceability in the security and privacy activities of the organization; to obtain individual accountability for any security or privacy actions; and to understand emerging trends in the security and privacy programs of the organization. References: [SP 800-30]; [SP 800-53A].

SECURITY AND PRIVACY REPORTING Task M-5 Report the security and privacy posture of the system to the authorizing official and other organizational officials on an ongoing basis in accordance with the organizational continuous monitoring strategy. Potential Inputs: Security and privacy assessment reports; plans of action and milestones; organization- and system-level risk assessment results; organization- and system-level continuous monitoring strategy; security and privacy plans; Cybersecurity Framework Profile. Expected Outputs: Security and privacy posture reports.¹⁰⁹ Primary Responsibility: System Owner; Common Control Provider; Senior Agency Information Security Officer; Senior Agency Official for Privacy. Supporting Roles: System Security Officer; System Privacy Officer. System Development Life Cycle Phase: New · Operations/Maintenance. Existing · Operations/Maintenance. ¹⁰⁹ If a comparable report meets the requirements of what is to be included in a security or privacy posture report (e.g., a report generated from a security or privacy management and reporting tool), then the comparable report would constitute the posture report.

. All executive agencies are required to comply with the same standards for protection of FCI and CUI in those regulations. Once attained, a current CMMC certification may be presented for consideration by any entity (including other government agencies) as an indicator that the security requirements associated with the certificate level (e.g., CMMC Level 2) have in fact been implemented. CMMC Program requirements are designed to ensure compliance with existing standards for protection of FCI and CUI and align directly to NIST guidelines (e.g., NIST SP 800-171 R2) and the basic safeguarding requirements of FAR clause 52.204-21 that apply to all executive agencies. Regulations issued by any executive agency must be aligned to these overarching requirements, therefore CMMC Program requirements will not conflict with any FCI or CUI safeguarding regulations that may be issued by other agencies as cited by the commenter. All executive agencies are permitted to submit and review comments as part of the formal rulemaking process, and additional coordination is not required. This rule provides a consistent way of verifying contractors' compliance with the referenced FAR and NIST requirements, in addition to those from NIST SP 800-172 Feb2021 where applicable. b. Requests To Recognize Alternate Standards Comment: Several commenters requested the rule be modified to accept or recognize alternate standards for the purpose of meeting CMMC assessment requirements. Some small to medium businesses recommended acceptance of healthcare relevant standards or other recognized certification frameworks as a substitute for CMMC and FedRAMP Equivalency. Another comment cited verbiage in the DFARS clause 252.204-7012 clause

that references DoD CIO approval to vary from NIST SP 800-171 requirements as rationale for revising the CMMC rule to permit acceptance of other standards such as the NERC Critical Infrastructure Protection standards which apply to North America's Bulk Electric System (BES). Some comments expressed concern that absent greater acceptance of the standards required by other agencies, companies complying with CMMC would be at a competitive disadvantage due to the perceived costs of complying with CMMC standards. Another comment expressed a similar concern but cited the need for acceptance of foreign C3PAOs to effectively scale CMMC to include assessment of foreign OSCs. (printed page 83147) Response: CMMC Program requirements apply to those contractors that seek to bid for DoD work which requires processing, storing, or transmitting FCI or CUI in a contractor owned information system. Section 170.20 addresses Standards Acceptance and delineates the only existing bases for accepting alternate standards in this rule. The DoD does not currently have standards acceptance with other Federal entities in lieu of the CMMC requirement.

And with the exception of publications that analyze the Security Rule, NIST's guidance does not specifically address the security of ePHI. CISA has issued cross-sector CPGs, but it is not ANSI-accredited. There may be other organizations that have set standards for the transmission of particular information, such as the secure transmission of images, but adopting such individual standards would not meet the Department's criteria. In this case, adoption of such standard would be far too granular and require the Department to revise the Security Rule at the same interval as the particular standard, which may be irregular. Additionally, given that the Department is limited to modifying each standard or implementation specification no more frequently than once every 12 months, this approach would be inefficient and could lead to a requirement that the Department update the Security Rule more than once a year, depending on when such individual standards or implementation specifications are revised. Even modifying the standards annually would require a significant investment of Department resources, not to mention the investment required of regulated entities to comply with an ever-changing set of requirements. Additionally, in 2021, Congress amended the HITECH Act to require the Secretary to consider whether a regulated entity has adequately demonstrated that it had in place recognized security practices for a certain period of time. [329] Congress defined 'recognized security practices' to include certain NIST publications; the approaches promulgated under (printed page 921) section 405(d) of the Cybersecurity Act of 2015; and other programs and processes that address cybersecurity and that are developed, recognized, or promulgated through regulations under other statutory authorities. [330]

- NICE released the National K12 Cybersecurity Education Roadmap with five major elements and accompanying strategies. - The NICE Community Coordinating Council launched five project teams that each support objectives from the NICE Strategic Plan. - NICE launched the Cybersecurity Apprenticeship Finder and supported a 120-Day Cybersecurity Apprenticeship Sprint in partnership with the U.S. Department of Labor. - A report, 'Measuring Cybersecurity Workforce Capabilities: Defining a Proficiency Scale for the NICE Framework', was submitted to Congress. - In response to the FY 2021 National Defense Authorization Act, NICE submitted a report to Congress on cybersecurity proficiencies and published cybersecurity career pathways information. - The Small Business Cybersecurity Corner released a series of videos with companion discussion guides on ransomware, phishing, and multi-factor authentication. - NIST continued to bring together the community through events, including the Federal Cybersecurity Workforce Summit and Webinars, Federal Information Security Educators (FISSEA) Forums, NICE Webinar Series, Cybersecurity Career Awareness Week, and by supporting the NICE Conference, NICE K12 Conference, and US Cyber Games through cooperative agreements.

<https://www.archives.gov/files/isoo/oversight-groups/nisp/2014-suitability-and-processes-report.pdf>). This review assessed USG policies, programs, processes, and procedures involving determinations of federal employee suitability, contractor fitness, and personnel security. The interagency working group also evaluated the collection, sharing, processing, and storage of information used to make suitability, credentialing, and security decisions. It found the need for better information sharing, increased oversight over background investigations, and consistent application of standards and policies for both Federal employees and contractors. The report identified 13 recommendations to improve how the Government performed suitability determinations and security clearances and the creation of SEAD 3 is a partial response to recommendation A.2. SEAD-3 requires enhanced additional reporting of foreign travel, foreign contacts and conduct/behavior that might jeopardize an individual from maintaining access or eligibility to access classified

information. Many of the requirements are a direct result of recent national security breaches by trusted insiders who have disclosed classified information to news media or foreign entities causing significant harm to the interests of the United States. SEAD 3 was designed to strengthen the safeguarding of national security equities, such as national security information, personnel, facilities, and technologies. These reporting requirements are important because individuals who incur a continuing security obligation need to be aware of the risks associated with foreign intelligence operations and/or possible terrorist activities directed against them in the U.S. and abroad, and to be aware they possess or have access to information that is highly sought after by foreign adversaries and competitors, including, but not limited to: Classified or sensitive information vital to national and economic security Emerging technologies and pioneering research and development Information relating to critical infrastructure sectors Proprietary secrets Security or counterintelligence information In particular, the risk of becoming an intelligence target increases greatly during foreign travel, be it for official or unofficial purposes. NISP Contractor cleared personnel can become the target of a foreign intelligence or security service at any time in any country. (printed page 83309) Collecting additional information on travel will help ensure basic counterintelligence awareness is implemented to effectively protect both the individual and the USG against foreign attempts to collect sensitive, proprietary, or classified information. Such measures could include arranging a pre-travel briefing from the entity Facility Security Officer. Reminders include, but are not limited to the following, which can be provided to:

This rule codifies the CMMC Program, elements of which are reflected in the CMMC Model. All CMMC Model requirements are derived from FAR 52.204-21, NIST SP 800-171 Rev 2, and NIST SP 800-172, which are configuration-controlled guidelines managed by NIST. As a result of the alignment of CMMC to NIST guidelines, the Department's requirements will continue to evolve as changes are made to the underlying NIST SP 800-171 Rev 2 and NIST SP 800-172 security requirements. Additional rulemaking may be necessary in the future to conform CMMC requirements described in this rule to any changes to the underlying information protection requirements defined in the foundational NIST guidelines.

Comment: Many comments were received requesting changes to CMMC Model 1.0. Several commenters requested changes to CMMC Level requirements and others had questions about the content and handling of CMMC Model updates. A few commenters made suggestions for restricting the current implementation, such as using only NIST SP 800-171 Rev 2 for the CMMC 1.0 implementation of Level 1-3 requirements and supplementing with additional requirements only in Levels 4 and 5. Similar comments recommended using NIST SP 800-171 Rev 2 for the initial CMMC rollout and later expanding to include additional CMMC requirements. A number of comments questioned the purpose and use of the CMMC 1.0 implementation of CMMC Level 2. Other comments requested information on updating CMMC requirements as new technology and threats emerge and new versions of NIST SP 800-171 Rev 2 and NIST SP 800-53 are released. Multiple comments were received on CMMC 1.0 Levels 4 and 5. Several commenters believed there to be a significant disconnect between NIST SP 800-171B/172 and CMMC 1.0 Levels 4 and 5, and issues with implementation of these levels. Many comments requested that Levels 4 and 5 be updated to allow for flexibility in implementation rather than require all the requirements as written. Reasons cited for allowing flexibility include reducing cost and assessment complexity as well as allowing for the ability to adapt based on architectural environments and dynamic threat models. Response: Changes were made in this rule to requirements in the former CMMC model based in part upon receipt of informal public comment. The CMMC Model was streamlined to three-tiers, which align to the protection requirements set forth in FAR 52.204-21, NIST SP 800-171 Rev 2, and NIST SP 800-172, and all CMMC-unique requirements and process maturity elements have been removed. The CMMC Model and program requirements will be evaluated as new technology and threats emerge and revised as appropriate. Comment: One comment included a request to identify instances where contractors would be better off using a classified environment, rather than CMMC version 1.0 Level 4 or 5, to protect the information. Response:

A CMMC Third-Party Assessment Organization (C3PAO) is an organization authorized by the Cyber AB to conduct CMMC Level 2 certification assessments. C3PAOs must meet specific qualifications including: employing certified CMMC assessors (CCAs), maintaining their own CMMC certification, following the CMMC Assessment Process (CAP), and being listed in the Cyber AB marketplace. During a CMMC Level 2 assessment, the C3PAO team evaluates the organization's implementation of all 110 NIST SP 800-171 security requirements through document review, interviews, and technical testing.

(incorporated by reference, see §.170.2), implementing DoD specified parameters to meet CMMC Level 3 requirements (see table 1 to §.170.14(c)(4) CMMC Level 3 Requirements). These additional

requirements are necessary to protect CUI being processed, stored, or transmitted in contractor information systems, when designated by a CMMC Level 3 requirement as defined by a DoD program manager or requiring activity. In general, the Department will identify a CMMC Level 3 requirement for solicitations supporting its most critical programs and technologies. (b) Program managers and requiring activities are responsible for identifying the CMMC Level that will apply to a procurement. Selection of the applicable CMMC Level will be based on factors including but not limited to: (1) Criticality of the associated mission capability; (2) Type of acquisition program or technology; (3) Threat of loss of the FCI or CUI to be shared or generated in relation to the effort; (4) Potential for and impacts from exploitation of information security deficiencies; and (5) Other relevant policies and factors, including Milestone Decision Authority guidance. (c) In accordance with the implementation plan described in § 170.3, CMMC Program requirements will apply to new DoD solicitations and contracts, and shall flow down to subcontractors who will process, store, or transmit FCI or CUI in performance of the subcontract, as described in § 170.23. (d) In very limited circumstances, a Service Acquisition Executive or Component Acquisition Executive in the DoD may elect to waive inclusion of CMMC Program requirements in a solicitation or contract, and in accordance with all applicable policies, procedures, and requirements. In such cases, contractors and subcontractors will remain obligated to comply with all applicable cybersecurity and information security requirements. (e) The CMMC Program does not alter any separately applicable requirements to protect FCI or CUI, including those requirements in accordance with FAR 52.204-21 (48 CFR 52.204-21), Basic Safeguarding of Covered Contractor Information Systems, or covered defense information in accordance with DFARS subpart 204.73 (48 CFR 204.73), Safeguarding Covered Defense Information and Cyber Incident Reporting, or any other applicable information protection requirements. The CMMC Program provides a means of verifying implementation of the security requirements set forth in FAR 52.204-21, NIST SP 800-171 Rev 2, and NIST SP 800-172, as applicable. Subpart B-Government Roles and Responsibilities § 170.6 CMMC PMO.

, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804 . III. Regulatory Flexibility Act DoD expects that this proposed rule may have an economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601 , et seq. Therefore, an Initial Regulatory Flexibility Analysis has been prepared and is summarized as follows: This rule would affect offerors that are owned by another business entity. As such, this DFARS rule would require an offeror to represent that, if it is owned or controlled by another business entity, it has entered the CAGE code and the name of that entity. DoD made 308,286 new contract awards to contractors with approximately 55,000 unique Data Universal Numbering System (DUNS) numbers in Fiscal Year 2011. Approximately 41,000 of these awards were to small-business unique DUNS. It is estimated that approximately 5% of these small business unique DUNS are corporations under another business entity. Therefore, DoD estimates that this rule will apply to approximately 2,050 small-business unique DUNS contractors. The rule does not duplicate, overlap, or conflict with any other Federal rules. There are no significant alternatives to accomplish the stated objectives of this rule. DoD invites comments from small business concerns and other interested parties on the expected impact of this rule on small entities. DoD will also consider comments from small entities concerning the existing regulations in subparts affected by this rule in accordance with 5 U.S.C. 610 . Interested parties must submit such comments separately and should cite 5 U.S.C. 610 (DFARS Case 2011-D044) in the correspondence. IV. Paperwork Reduction Act The rule contains information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). Accordingly, DoD has submitted a request for approval of a new information collection requirement concerning Ownership of Offeror (DFARS Case 2011-D044) to the Office of Management and Budget. A. Public reporting burden for this collection of information is estimated to average 0.5 hours per response, including the time for reviewing instructions, searching existing data sources, gathering and maintaining the data needed, and completing and reviewing the collection of information. The annual reporting burden estimated as follows: Respondents: 308,286. Responses per respondent: 1.5. Total annual responses: 462,429. Preparation hours per response: 0.5 hours. Total response burden hours: 231,215 hours. B. Request for Comments Regarding Paperwork Burden. Written comments and recommendations on the proposed information collection, including suggestions for reducing this burden, should be sent to Ms. Jasmeet Sehra at the Office of Management and Budget, Desk Officer for DoD, Room 10236, New Executive Office Building, Washington, DC 20503, or email Jasmeet_K._Sehra@omb.eop.gov ,

of Action and Milestones PRA·Paperwork Reduction Act RM·Risk Management SAM·System for Award Management SC·System and Communications Protection SCADA·Supervisory Control and Data Acquisition SI·System and Information Integrity SIEM·Security Information and Event Management SP·Special Publication SPRS·Supplier Performance Risk System SSP·System Security Plan (b) Definitions. Unless otherwise noted, these terms and their definitions are for the purposes of this part. Access Control (AC) means the process of granting or denying specific requests to obtain and use information and related information processing services; and/or entry to specific physical facilities (e.g., federal buildings, military establishments, or border crossing entrances), as defined in FIPS 201-3 (incorporated by reference, see §·170.2). Accreditation means a status pursuant to which a CMMC Assessment and Certification Ecosystem member (person or organization), having met all criteria for the specific role they perform including required ISO/IEC accreditations, may act in that role as set forth in §·170.8 for the Accreditation Body and §·170.9 for C3PAOs. (CMMC-custom term) Accreditation Body is defined in §·170.8 and means the organization responsible for authorizing and accrediting members of the CMMC Assessment and Certification Ecosystem, as required. The Accreditation Body must be approved by DoD. At any given point in time, there will be only one Accreditation Body for the DoD CMMC Program. The current Accreditation Body is doing business as the Cyber AB at cyberab.org. (CMMC-custom term) Advanced Persistent Threat (APT) means an adversary that possesses sophisticated levels of expertise and significant resources that allow it to create opportunities to achieve its objectives by using multiple attack vectors (e.g., cyber, physical, and deception). These objectives typically include establishing and extending footholds within the information technology infrastructure of the targeted organizations for purposes of exfiltrating information, undermining or impeding critical aspects of a mission, program, or organization; or positioning itself to carry out these objectives in the future. The advanced persistent threat pursues its objectives repeatedly over an extended period-of-time, adapts to defenders' efforts to resist it, and is determined to maintain the level of interaction needed to execute its objectives, as is defined in NIST SP 800-39, (incorporated by reference, see §·170.2). Assessment means the testing or evaluation of security controls to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for an information system or organization, as defined in §·170.15 to §·170.18. (CMMC-custom term) (i) Self-Assessment

(3) In the case of material which was inadvertently released as UNCLASSIFIED, the contractor will mark and protect the notice as classified at the CONFIDENTIAL level, unless it contains additional information warranting a higher classification. The contractor will cite the applicable Contract Security Classification Specification, or equivalent, or other classification guide on the ·Derived From· line and mark the notice with an appropriate declassification instruction. (k) Dissemination of improperly marked information. If the contractor inadvertently distributes classified material without the proper classification assigned to it, or without any markings to identify the material as classified, as appropriate, the contractor will: (1) Determine whether all holders of the material are cleared and authorized access to it. (2) If recipients are authorized persons, and the contractor disseminated the information through authorized channels, promptly provide written notice to all holders of the proper classification to be assigned. The contractor will also include the classification source as well as declassification instructions in the notification. (3) Report compromises to the CSA in accordance with the provisions of §·117.8(d), if: (i) Any of the recipients of the material are not authorized persons. (ii) Any material cannot be accounted for. (iii) The material was transmitted through unauthorized channels. (printed page 83339) (l) Marking foreign government classified material. Foreign government classified information will retain its original classification markings or will be assigned a U.S. classification that provides a degree of protection at least equivalent to that required by the foreign government entity that furnished the information in accordance with 32 CFR 2001.54 . The equivalent U.S. classification and the country of origin will be marked on the front and back in English. (m) Foreign government restricted information and ·in confidence· information. (1) Some foreign governments have a fourth level of classification that does not correspond to an equivalent U.S. classification that is identified as RESTRICTED information. In many cases, security agreements require RESTRICTED information to be protected as U.S. CONFIDENTIAL information. (2) Some foreign governments may have a category of unclassified information that is protected by law. This latter category is normally provided to other governments with the expectation that the information will be treated ·In Confidence·. The foreign government or international organization must state that the information is provided in confidence and that it must be protected from release. (i) 10 U.S.C. 130c protects information provided ·In Confidence· by foreign governments which is not classified but meets

special requirements. (ii) This provision also applies to RESTRICTED information which is not required by an agreement to be protected as classified information.

From the NIST SP 800-172 Rev 3 Final Public Draft: Appropriately scoping security requirements is an important factor in determining protection-234 related investment decisions and managing security risks for nonfederal organizations. If nonfederal organizations designate specific system components to process, store, or transmit CUI associated with a critical program or a high value asset, those organizations may limit the scope of the security requirements by isolating the system components in a separate CUI security domain. Isolation can be achieved by applying architectural and design concepts (e.g., implementing subnetworks with firewalls, software-defined perimeters, micro-segmentation, zero trust network architectures, and information flow control mechanisms). Security domains may employ physical separation, logical separat

of November 4, 2010, entitled "Controlled Unclassified Information," establishes a program to standardize executive branch management of information that requires safeguarding or dissemination controls. The National Archives and Records Administration's (NARA) Information Security Oversight Office (ISOO) is the executive agent for the Controlled Unclassified Information Program. (b) This section implements 32 CFR part 2002, Controlled Classified Information (CUI). (c) Part 24, Protection of Privacy and Freedom of Information, contains additional policy and procedures for safeguarding records that are protected by the Privacy Act. (d) Part 27, Patents, Data, and Copyrights, contains policy and procedures for safeguarding information in patent applications and patents. 4.403-3 Applicability. (a) The requirements for safeguarding CUI in this section apply when an offeror or contractor is expected to handle CUI, including instances when CUI resides on or transits through contractor information systems or within contractor facilities. (b) The CUI requirements in the clause at 52.204-XX, Controlled Unclassified Information, apply when CUI will be involved in the contract. The CUI requirements in the clause at 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information, apply when no CUI will be involved in the contract. 4.403-4 Policy. (a) The requiring activity will identify any CUI in the standard form (SF) XXX, Controlled Unclassified Information (CUI) Requirements, which must be incorporated in the contract. Contractors are required to safeguard only the CUI that is identified in the SF XXX. However, see 52.204-XX(c)(2). (b) Offerors and contractors are required to safeguard CUI pursuant to section 4.403-2. For CUI identified on an SF XXX that is incorporated into a contract, the contractor shall comply with the CUI requirements in the clause at 52.204-XX and on the form itself. (c) Unmarked or mismarked CUI is not considered a CUI incident unless the mismarking or lack of marking has resulted in the mishandling or improper dissemination of the information. Offerors are requested, and contractors are required, to notify the Government within 8 hours of discovery if they discover during the solicitation phase or performance of a contract any information they suspect is CUI, but is not listed on an SF XXX or is not marked or properly marked as required by an SF XXX. Offerors and contractors are not responsible for identifying or marking unmarked or mismarked CUI that is not identified in the SF XXX. (d) The Government shall protect against the improper use or release of information that includes contractor proprietary business information or contractor-attributional information to the extent required by law. (e) Applicable CUI requirements can be waived by the Government in accordance with 32 CFR 2002.38. 4.403-5 Procedures.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of technical, physical, administrative, and management standards and guidelines for the cost-effective security and privacy of sensitive unclassified information in Federal computer systems. This Special Publication 800-series reports on ITL's research, guidance, and outreach efforts in computer security, and its collaborative activities with industry, government, and academic organizations.

Under the proposed rule, the CMMC Program will require all DoD contractors and subcontractors who handle Federal contract information (FCI) and Controlled Unclassified Information (CUI) to maintain cybersecurity protections of their systems. CMMC will create three levels of compliance, depending on the level of security necessary for which the contractor has access. Level 1 has 15 requirements focused on logging access to potential FCI. Level 2 includes minimum requirements for contractors

handling CUI and adds 110 requirements. Level 3 addresses an additional 24 requirements. Each level will pose varying challenges for small businesses of every kind to comply with the progressing requirements. Advocacy has commented on previous proposals for CMMC concerning the significant impact this will have on small business contractors. · Advocacy held outreach meetings with diverse small business stakeholders concerning this rule, both in-person and virtually. · Small businesses expressed concerns with how to compensate the increased costs due to implementing CMMC and asked for clarity on aspects of the proposed CMMC rule. Advocacy has four chief concerns with the proposed rule. · Advocacy requests clear and concise guidance for small business contractors and subcontractors to create enclaves in order to lessen the burden of compliance on the businesses. · The proposed rule states that different business segments or different enclaves of a business can be assessed or certified at different CMMC levels. Creating and implementing enclaves will be most effective when a large prime contractor creates these enclaves to ease the burden on small subcontractors. The rule mentions the use of enclaves but does not provide guidance on how to implement enclaves within a business. · DoD Response: The Department acknowledges the concerns articulated by the Small Business Administration (SBA) and commits to enhancing training provisions after the rule is final and effective. Moreover, the Department pledges to reinstate outreach endeavors targeting the broader industry and specifically small businesses to facilitate familiarity with CMMC requirements once the rule is final and effective. However, the Department does not intend to formulate specific directives (printed page 83203) pertaining to the configuration and segregation of corporate information systems into enclaves. Such determinations must be tailored to individual companies, considering a multitude of unique factors. External service providers (ESPs) will be a driving force for small businesses' compliance with CMMC requirements. ESPs are vendors that handle security related data or CUI on their own assets and software. The ability of ESPs to create effective and economically feasible services will allow businesses to enclave different operations more easily and avoid unduly costly compliance expenses. · SBA Comment 2:

Appropriate management practices are essential to operating and maintaining a secure server. Security practices entail the identification of an organization's information system assets and the development, documentation, and implementation of policies, standards, procedures, and guidelines that help to ensure the confidentiality, integrity, and availability of information system resources. To ensure the security of a server and the supporting network infrastructure, the following practices should be implemented: The classic model for information security defines three objectives of security: maintaining confidentiality, integrity, and availability. Confidentiality refers to protecting information from being accessed by unauthorized parties. Integrity refers to ensuring the authenticity of information-that information is not altered, and that the source of the information is genuine. Availability means that information is accessible by authorized users. Each objective addresses a different aspect of providing protection for information. - GLYPH<c=31;font=MIJOHI+Webdings> 'The potential impact is LOW if the loss of confidentiality, integrity, or availability could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals. A limited adverse effect means that, for example, the loss of confidentiality, integrity, or availability might (i) cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced; (ii) result in minor damage to organizational assets; (iii) result in minor financial loss; or (iv) result in minor harm to individuals.

164.310 to clarify that the Security Rule requires that physical safeguards be applied to all ePHI in the possession of the regulated entity, that is, throughout the regulated entity's facilities. The Department also proposes to expand this section to expressly require a regulated entity to implement physical safeguards in accordance with not only 45 CFR 164.306 , but also 45 CFR 164.316 to connect the overarching documentation requirements. Consistent with the proposals to revise the general requirements in 45 CFR 164.306(c) and (d) , the Department proposes to remove any distinction between addressable and required implementation specifications in this section such that all specifications would be required. Also consistent with changes proposed elsewhere in this NPRM, the Department proposes to modify all four physical safeguard standards to require that the requisite policies and procedures be in writing [645] and implemented throughout the enterprise. [646] Under this proposal, a regulated entity that could not produce a written policy describing how it will implement a required physical safeguard and demonstrate that the safeguard is in effect and operational throughout the enterprise would not be in compliance with the standard. Consistent with our proposals to require that regulated entities maintain their

administrative safeguards, the Department also proposes to require a regulated entity to maintain its security measures by reviewing and testing the required security measures at least once every 12 months, and by modifying the same as reasonable and appropriate. Additionally, we propose to modify certain standards and implementation specifications to ensure that regulated entities understand their obligations to ensure the confidentiality, integrity, and availability of ePHI by implementing physical safeguards to protect their relevant electronic information systems and/or the technology assets in their relevant electronic information systems. b. Section 164.310(a)(1)-Standard: Facility Access Controls The Department proposes to modify the standard for facility access controls at 45 CFR 164.310(a)(1) to clarify that the policies and procedures required by this standard must be in writing and address physical access to all of a regulated entity's relevant electronic information systems and the facility or facilities in which these systems are housed and to add a paragraph to clarify the organization of the regulatory text. The Department also proposes to modify the implementation specifications associated with the standard for facility access controls. Specifically, we propose to modify the implementation specifications for contingency operations, facility security plan, and access control and validation procedures at 45 CFR 164.310(a)(2)(i) through (iii) to clarify that we expect a regulated entity to not only establish and implement policies and procedures, but also that we expect them to be in writing.

109 If a comparable report meets the requirements of what is to be included in a security or privacy posture report (e.g., a report generated from a security or privacy management and reporting tool), then the comparable report would constitute the posture report. NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

CHAPTER THREE PAGE 81 This publication is available free of charge from:

<https://doi.org/10.6028/NIST.SP.800-37r2> Discussion: The results of monitoring activities are documented and reported to the authorizing official and other selected organizational officials on an ongoing basis in accordance with the organizational continuous monitoring strategy. Other organizational officials who may receive security and privacy posture reports include, for example, chief information officer, senior agency information security officer, senior agency official for privacy, senior accountable official for risk management or risk executive (function), information owner or steward, incident response roles, and contingency planning roles. Security and privacy posture reporting can be event-driven, time-driven, or event- and time-driven.¹¹⁰ The reports provide the authorizing official and other organizational officials with information regarding the security and privacy posture of the systems including the effectiveness of implemented controls. Security and privacy posture reports describe the ongoing monitoring activities employed by system owners or common control providers. The reports also include information about security and privacy risks in the systems and environments of operation discovered during control assessments, auditing, and continuous monitoring and how system owners or common control providers plan to address those risks. Organizations have flexibility in the breadth, depth, formality, form, and format of security and privacy posture reports. The goal is efficient ongoing communication with the authorizing official and other organizational officials as necessary, conveying the current security and privacy posture of systems and environments of operation and how the current posture affects individuals, organizational missions, and business functions. At a minimum, security and privacy posture reports summarize changes to the security and privacy plans, security and privacy assessment reports, and plans of action and milestones that have occurred since the last report. The use of automated security and privacy management and reporting tools (e.g., a dashboard) by the organization facilitates the effectiveness and timeliness of security and privacy posture reporting. The frequency of security and privacy posture reports is at the discretion of the organization and in compliance with federal and organizational policies. Reports occur at appropriate intervals to transmit security and privacy information about systems or common controls but not so frequently as to generate unnecessary work or expense. Authorizing officials use the security and privacy posture reports and consult with the senior accountable official for risk management or risk executive (function), senior agency information security officer, and senior agency official for privacy to determine if a reauthorization action is necessary. Security and privacy posture reports are marked, protected, and handled in accordance with federal and organizational policies. Security and privacy posture reports can be used to satisfy FISMA reporting requirements for documenting remediation actions for security and privacy weaknesses or deficiencies. Reporting on security and privacy posture is intended to be ongoing and should not be interpreted as requiring the time, expense, and formality associated with the information provided

for the initial authorization. Rather, reporting is conducted in a cost-effective manner consistent with achieving the reporting objectives. References: [SP 800-53A]; [SP 800-137]; [NIST CSF] (Core [Identify, Protect, Detect, Respond, Recover Functions]). ONGOING AUTHORIZATION Task M-6 Review the security and privacy posture of the system on an ongoing basis to determine whether the risk remains acceptable. Potential Inputs: Risk tolerance; security and privacy posture reports; plans of action and milestones; organization- and system-level risk assessment results; security and privacy plans. Expected Outputs: A determination of risk; ongoing authorization to operate, ongoing authorization to use, ongoing common control authorization; denial of ongoing authorization to operate, denial of ongoing authorization to use, denial of ongoing common control authorization. 110 See Appendix F for additional information about time- and event-driven authorizations and reporting.

Ms. Angela James. Requests for copies of the information collection proposal should be sent to Ms. James at whs.mc-alex.esd.mbx.dd-dod-information-collections@mail.mil. Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. [FR Doc. 2020-11477 Filed 5-27-20; 8:45 am] BILLING CODE 5001-06-P

for procuring the devices quite often is not an expert at all.' The availability of sample procurement language can be of great benefit in improving the security of products procured by organizations. Most workshop participants agreed that manufacturers of IoT devices currently lack market incentives to prioritize cybersecurity as a concern when designing, marketing, and supporting their products. Some counterexamples were presented in which informed customers do recognize the advantages of enhanced security. This suggests that enhanced cybersecurity could demonstrably be a market advantage if it is emphasized. Workshop poll results showed strong support (71 %) for government mandates as a mechanism for enhancing IoT cybersecurity (poll #4), and general agreement (55 %) that developers of IoT devices currently lack appropriate incentives to secure their products (poll #2). Participants supported a mixture of regulatory guidance, customer education, supply chain pressures, and other considerations to create the economic incentives to shift the overall IoT device market toward enhanced cybersecurity.

The two addressable implementation specifications for the transmission security standards are under 45 CFR 164.312(e)(2). The implementation specification for integrity controls requires a regulated entity, when it is reasonable and appropriate, to implement security measures to ensure that electronically transmitted ePHI is not improperly modified without detection until the ePHI has been disposed. [682] The implementation specification for encryption requires a regulated entity, when it is reasonable and appropriate, to implement a mechanism to encrypt ePHI. (printed page 964) 2. Issues To Address While the intention of 45 CFR 164.312 is for regulated entities to develop and put into place technical controls, the Department is aware that regulated entities have not always achieved the degree of protection for ePHI that we intended. Absent a definition of 'implement,' some regulated entities might interpret the term to mean something other than implementing technical controls to ensure the confidentiality, integrity, and availability of ePHI. This misinterpretation may leave ePHI partially unprotected because regulated entities may not implement safeguards throughout their enterprise. As discussed above with respect to both the administrative and physical safeguards, the Department is also concerned that regulated entities are not making the connection between the maintenance requirement at 45 CFR 164.306(d) and the requirement to implement technical safeguards, and therefore, are not reviewing or updating their policies and procedures for technical safeguards. Additionally, the Department believes that regulated entities may not be recognizing that their obligations under the Security Rule to protect ePHI are not limited to protecting electronic information systems that create, receive, maintain, or transmit ePHI, but necessarily include other electronic information systems that affect the confidentiality, integrity, or availability of ePHI. While the Security Rule relies on a flexible and scalable approach to compliance, the health care industry's shift to a digital environment has substantially increased both the risk to ePHI and the prevalence of technological solutions for addressing those risks. Additionally, the cost of such solutions has, in many cases, decreased over time, as is often the case with technology. For example, when the original Security Rule was published, tools to encrypt ePHI had limited availability, were more costly, and were not user-friendly, particularly for small health care providers. [683] By contrast, in 2024, the technical ability to encrypt data may be seamless in many applications, inexpensive, and widely available in commercial software and hardware products. [684] Where an encryption solution is not integrated into an application, software, or hardware, third-party solutions are often

available. [685] Thus, we do not believe that it is appropriate for such provisions to be addressable. [686]

Do not leave items that would be of value to a foreign intelligence service unattended in hotel rooms or stored in hotel safes. Limit sensitive discussions hotel rooms or other public places are not suitable locations to discuss sensitive information. Not use computer or facsimile equipment at foreign hotels or business centers for sensitive matters. Not divulge information to anyone unauthorized to hear it. Ignore or deflect intrusive inquiries or conversation about business or personal matters. Keep a laptop computer as carry-on baggage never check it with other luggage and, if possible, remove or control storage media. Confirm before the foreign travel whether it is necessary or even advisable to take a laptop computer. Report any suspicious contacts or incidents to the entity FSO to report to the applicable CSA. Contractors in the NISP also have a responsibility for recognizing and avoiding personal behaviors and activities that may impact their continued eligibility for access to classified information. This includes, but is not limited to the following activities which may be of potential security, insider threat, or counterintelligence concern An unwillingness to comply with rules, regulations, or security requirements Unexplained affluence or excessive indebtedness Alcohol abuse Illegal use or misuse of drugs or drug activity Apparent or suspected mental health issues where there is reason to believe it may impact the individual's ability to protect classified information or other information prohibited by law from disclosure Criminal conduct Any activity that raises doubts as to whether the individual's continued national security eligibility is clearly consistent with national security interests Misuse of U.S. Government property or information systems This rule will result in fewer contract performance delays by the small number of U.S. contractors with NTIB ownership operating under an SSA. With Section 842 of Public Law 115-232 implemented there will no longer be at least a 60 day minimum delay for USG contracting activities and NTIB covered entities to wait for NIDs after contract award for access to proscribed information when all other requirements have been met. When a GCA submits a NID to the applicable CSA, there is an initial 30 days to process the request, which includes verification of the NID requirement. If the NID also includes a requirement for controlling agency concurrence (i.e., ODNI for SCI, DOE for RD or NSA for COMSEC), the CSA submits the request to the applicable controlling agencies who then have 30 more days for its analysis and decision. Section 842 of Public Law 115-232 is deregulatory by statute as reflected in this rule. Congress required that the NTIB policy framework foster a defense free-trade area among the defense-related research and development sectors of the United States, Canada, Australia and the United Kingdom. Section 881 of Public Law 114-328

(L) From subsection (g) because portions of this system of records are compiled for law enforcement purposes and have been exempted from the access provisions of subsections (d) and (f). (printed page 14755) (19) System identifier and name. A0195-6 USACIDC, Criminal Investigation Accreditation and Polygraph Examiner Evaluation Files. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7) , but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (D) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) , (k)(5), or (k)(7) from subsections 5 U.S.C. 552a (c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) , (k)(5), and (k)(7). (iii) Reasons. (A) From subsections (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious

impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought.

The Department is concerned about the potential effects of such incidents in health care, where they would jeopardize the confidentiality, integrity, and availability of ePHI. Finally, consistent with the concerns expressed above about the implications of recent caselaw and the uncertainty it might cause among regulated entities assessing whether they have adequately protected their ePHI, the Department is concerned that the existing Security Rule may not provide sufficient instruction to regulated entities about (printed page 965) how they must maintain specific security measures.

3. Proposals The Department retains the requirements for technical safeguards generally and proposes additions and modifications to the existing standards and implementation specifications.

a. Section 164.312·Technical Safeguards The Department proposes to expand the primary provision at 45 CFR 164.312 to clarify that regulated entities as a general matter must implement and document the implementation of technical safeguards adopted for compliance with the Security Rule. This proposal would clarify that the requirement to implement and document technical safeguards would apply to all technical safeguards, including technical controls, implemented by a regulated entity to protect the confidentiality, integrity, and availability of all ePHI it creates, receives, maintains, or transmits. As noted above, the current provision at 45 CFR 164.312 does not reference the documentation requirements in 45 CFR 164.316 . Therefore, for clarity, we propose to explicitly require in 45 CFR 164.312 that documentation of technical safeguards conforms to the requirements in 45 CFR 164.316 . This proposed change would clarify that a regulated entity must document the policies and procedures required to comply with this rule and how entities considered the flexibility factors in 45 CFR 164.306(b) . It would also clarify that a regulated entity must document each action, activity, and assessment required by the Security Rule. The Department considers the documentation requirements and other provisions of 45 CFR 164.316 to apply to all of the safeguards, including the technical safeguards, and this proposal is intended to remove any potential uncertainty among regulated entities. Additionally, we propose to add maintenance requirements separately to the implementation specifications for particular technical safeguards in 45 CFR 164.312 , as discussed below and consistent with our proposals to add similar requirements to particular administrative and physical safeguards.

A final regulatory flexibility analysis (FRFA) has been prepared consistent with the Regulatory Flexibility Act, 5 (printed page 19692) U.S.C. 601, et seq. The FRFA is summarized as follows: The Department of Defense is amending the Defense Federal Acquisition Regulation Supplement (DFARS) to modify the text of DFARS clause 252.204-7002, Payment for Subline Items Not Separately Priced, to simplify and conform the clause text to current Government contract line item structure terminology. The objective of this rule is to clarify the intent of the clause for contractors, when submitting invoices under contracts that contain items that are not separately priced. The modification of this DFARS clause supports a recommendation from the DoD Regulatory Reform Task Force. No public comments were received in response to the initial regulatory flexibility analysis. Based on an average of data for fiscal year 2016 through 2018 from the Federal Procurement Data System and Electronic Document Access, DoD awards approximately 12,435 contracts annually that includes the DFARS clause 252.204-7002. Of the 12,435 awards, approximately 4,924 contracts (40%) are awarded to 1,564 unique small business entities. Based on the available data and the objective of the rule, DoD does not anticipate that this proposed rule will significantly impact small business entities. This rule does not include any new reporting, recordkeeping, or other compliance requirements for small businesses. This rule does not duplicate, overlap, or conflict with any other Federal rules. There are no known significant alternative approaches to the rule that would meet the stated objectives. VI. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). List of Subjects in 48 CFR Parts 204 and 252 Government procurement Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204 and 252 are amended as follows: 1. The authority citation for 48 CFR parts 204 and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 . PART 204-ADMINISTRATIVE AND INFORMATION MATTERS 2. Amend section 204.7104-1: a. In paragraph (b)(3)(iii), by removing ·subsection· and adding ·section· in its place; and b. By revising paragraph (b)(3)(iv). The revision reads as follows: 204.7104-1 Criteria for establishing. * *

* * * (b) * * * (3) * * * (iv) When the price for items not separately priced is included in the price of another contract line or subline item, it may be necessary to withhold payment on the priced contract line or subline item until the included line or subline items that are not separately priced have been delivered. See the clause at 252.204-7002, Payment for Contract Line or Subline Items Not Separately Priced. 3. Revise section 204.7109 to read as follows: 204.7109 Contract clauses.

(9) A DA activity will notify requesters seeking National Security Council (NSC) or White House documents that they should write directly to the NSC or White House for such documents. DA documents in which the NSC or White House have a concurrent reviewing interest will be forwarded to the Department of Defense, Office of Freedom of Information and Security Review, which will coordinate with the NSC or White House, and return the documents to the originating DA activity after NSC or White House review. NSC or White House documents discovered in DA activity files which are responsive to a Privacy Act request will be forwarded to DOD for coordination and return with a release determination. (10) To the extent referrals are consistent with the policies expressed above; referrals between offices of the same DA activity are authorized. (l) Reproduction fees. (1) Use fees only to recoup direct reproduction costs associated with granting access. (2) DA activities may use discretion in their decision to charge for the first copy of records provided to an individual to whom the records pertain. Thereafter, fees will be computed pursuant to the fee schedule set forth in AR 25-55, including the fee waiver provisions. (3) Checks or money orders for fees should be made payable to the Treasurer of the United States and will be deposited in the miscellaneous receipts of the treasury account maintained at the activity's finance office. (4) Reproduction costs shall only include the direct costs of reproduction and shall not include costs of: (i) Time or effort devoted to searching for or reviewing the records by personnel; (ii) Fees not associated with the actual cost of reproduction; (iii) Producing a copy when it must be provided to the individual without cost under another regulation, directive, or law; (iv) Normal postage; (v) Transportation of records or personnel; or (vi) Producing a copy when the individual has requested only to review the records and has not requested a copy, and the only means of allowing review is to make a copy (e.g., the records are stored in a computer and a copy must be printed to provide individual access, or the activity does not wish to surrender temporarily the original records for the individual to review). (m) Privacy Act case files. (1) Whenever an individual submits a Privacy Act request, a case file will be established. This Privacy Act case file is a specific type of file that is governed by a specific Privacy Act system of records notice. In no instance will the individual's Privacy Act request and corresponding Army actions be included in the individual's military personnel file or other military filing systems, such as adverse action files or general legal files, and in no instance will the Privacy Act case file be used to (printed page 24503) make an adverse determination about the individual. (2) The case file will be comprised of the request for access/amendment, grants, refusals, coordination action(s), and all related papers. § 505.6

(Response) Foreign persons, except those who transport food in the United States, are not subject to this final rule; however, persons that import food from foreign countries are subject to the rule. FDA believes that the compliance timeframes specified in § 1.368 of this final rule give all persons subject to this final rule, including importers, sufficient time to determine what steps are needed to be able to comply with the final rule, and to be in compliance on their respective compliance dates, while allowing FDA to meet its statutory objective of ensuring that persons that manufacture, process, pack, hold, transport, distribute, receive, or import food in the United States establish and maintain records that will significantly improve FDA's ability to address credible threats of serious adverse health consequences or death to humans or animals. (Comment 173) One comment states that the proposed delay in the compliance date for small businesses does not adequately address small business needs. One comment states that FDA should provide businesses with additional assistance with compliance. (Response) FDA has increased the compliance period for small businesses from 12 months to 18 months, and for very small businesses from 18 months to 24 months. With respect to additional assistance, in accordance with the Small Business Regulatory Enforcement Fairness Act of 1996 (SBREFA), FDA plans to publish a small entities compliance guide to assist small and very small businesses with complying with the recordkeeping requirements. As described previously, FDA also plans to conduct outreach activities to explain the requirements of this final rule to affected entities. (Comment 174) One comment states that the phase-in for small and very small businesses is not a good idea because if the consequences are as grave as FDA claims, everyone must be required to comply at the earliest possible time, allowing for systems and procedural development and employee

training. The comment states that a phase-in of the regulations would pose a threat to public health and safety, should not be part of this regulation, and would be against the public interest. (Response) The Bioterrorism Act specifically states that, in issuing these regulations, the Secretary shall take the size of a business into account. FDA considered reduced requirements for, or even exempting, small businesses. However, most food products and ingredients pass through at least one small business during commerce. In addition, more than 80 percent of the covered entities are considered very small businesses. If FDA were to exempt small businesses from these regulations, permit shorter record retention periods, or subject them to reduced records requirements, FDA's tracing investigations would be severely compromised. Given the foregoing, FDA believes it is appropriate to give small and very small businesses additional time to come into compliance with the regulations.

| ID | Description |
|-----|-----| | CWE-1272 |
Sensitive Information Uncleared Before Debug/Power State Transition | | CWE-1300 | Improper Protection of Physical Side Channels | | CWE-1189 | Improper Isolation of Shared Resources on System-on-a-Chip (SoC) | | CWE-1244 | Internal Asset Exposed to Unsafe Debug Access Level or State | | CWE-1191 | On-Chip Debug and Test Interface with Improper Access Control | | CWE-1231 | Improper Prevention of Lock Bit Modification | | CWE-1233 | Security-Sensitive Hardware Controls with Missing Lock Bit Protection | | CWE-1274 | Improper Access Control for Volatile Memory Containing Boot Code | | CWE-1260 | Improper Handling of Overlap Between Protected Memory Ranges | | CWE-1240 | Use of a Cryptographic Primitive with a Risky Implementation | | CWE-1256 | Improper Restriction of Software Interfaces to Hardware Features | ## 3.1.

(Response) FDA has carefully considered these comments and agrees that businesses should be given additional time to comply in view of the programming, training, and business practice adjustments that will be needed. Section 1.368 of the final rule requires large businesses (500 or more full-time equivalent employees) to be in compliance within December 9, 2005. Small businesses (those with fewer than 500, but more than 10 full-time equivalent employees) must be in compliance within June 9, 2005, and very small businesses that employ 10 or fewer full-time equivalent employees must be in compliance within December 11, 2006. The extended compliance times for small and very small businesses are based on the total number of full-time equivalent employees within the entire business, not just at each individual establishment. FDA does not believe that extending more time is appropriate given the need for the regulations to help improve FDA's ability to address credible threats of serious adverse health consequences or death to humans or animals from accidental or deliberate contamination of food. In the event of an outbreak of foodborne illness, such information will help FDA and other authorities determine the source and cause of the event. In addition, the information will enable FDA to notify more quickly the consumers and/or facilities that might be affected by the outbreak. Further, the Bioterrorism Act directs FDA to take into account the size of a business in promulgating regulations. Consistent with this provision, FDA has: (1) Provided a full exemption for very small retailers based on the rationale stated previously; (2) provided a partial exemption for small (11 to 500 employees) and large (more than 500 employees) retailers from having to establish and maintain records as to immediate subsequent recipients; and (3) provided extended compliance times for very small businesses and small businesses in all sectors. (Comment 163) Some comments state that the transportation chain information requirements, by themselves, are so complex they simply cannot be developed in such a short timeframe even if industry were not dealing with several other major security-related regulatory efforts under the Trade Act of 2002 and the Maritime Transportation Security Act of 2002. (printed page 71610) The comments ask FDA to require more reasonable timetables that would be less costly and have a more realistic chance of successful compliance. (Response) As stated in the response to the comment 162, FDA has modified the compliance timeframes proposed. The final rule gives covered persons 12, 18, or 24 months after the date of publication to come into compliance, depending on the size of the business. The extended compliance times for small and very small businesses are based on the total number of full-time equivalent employees within the entire business, not just at each individual establishment.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 based on [Assignment:
organization-defined circumstances for physical or logical 2063

1. Description / Extended Description Detailed explanation of the fault type 2. Relationships /

Memberships Taxonomic information to organize weaknesses into hierarchies and categories 3. Modes of Introduction Descriptions of the life cycle phase in which the CWE can be introduced 4. Applicable Platforms Involved languages and technologies 5. Common Consequences Affected security attributes and likelihoods (e.g., confidentiality, integrity, availability, access control, authentication, and authorization) 6. Demonstrative Examples Hypothetical examples of the weakness 7. Observed Examples Actual observed examples of the weaknesses, usually with CVE references 8. Potential Mitigations Protection methods - Authentication (i.e., proving the identity of an actor) - Authorization (i.e., ensuring that a given actor can access a resource) - Accountability (i.e., tracking the activities that were performed) 2. An attacker can unlock hardware (e.g., to enter debug mode) using leaked or stolen credentials that were often necessarily shared among multiple entities (e.g., for hardware products not created by a single company, via vertical integration) [CWE1273]. 3. An attacker can obtain sensitive information from debug messages that unnecessarily reveal security details, often reducing security by obscurity (e.g., location of password hashes) [CWE-1295]. 4. An attacker can obtain security-relevant state information by observing different behaviors that are indicative of the hardware state (e.g., in timing, responses, and control flow) [CWE-203]. 5. An attacker can obtain security-sensitive information by leveraging physical access to the hardware to measure phenomena (e.g., physical side channels, such as real-time power consumption) [CWE-1300] [CWE-1255]. 6. An attacker can obtain sensitive data by evaluating and probing shared microarchitectural resources in contexts that should be isolated (e.g., caches and branch prediction logic) [CWE-1303]. 7.

)) have been the basis for CDRH's Classification Product Code structure and organization. These 16 Panels have largely been the driving force for CDRH's internal organizational structure as well. These Panels were established with the 1976 Medical Device Amendments, and rulemaking is required in order to add to or modify the Panels. However, rulemaking has resulted in very few additions or modifications to the Panels and subgroups since 1976. In order to respond to the evolution of device technology, classification product codes were created to assist in accurate identification and tracking of current medical devices and to allow for tracking and easy reference of predicate device types. Classification product codes are a method of classifying medical devices. CDRH and a subset of CBER-regulated medical device product codes consist of a three-letter combination that associates a device's type with a product classification designated for the application. Classification product codes and information associated with these devices, such as names and attributes, are assigned by CDRH to support their regulation. The purpose of this guidance document is to educate regulated industry and FDA Staff on how, when, and why to use classification product codes for medical devices regulated by CDRH and CBER. This document describes how classification product codes are used in a variety of FDA program areas to regulate and track medical devices. This document is limited to medical devices as defined in section 201(h) of the Federal Food, Drug, and Cosmetic Act (21 U.S.C. 321(h)) and does not discuss classification products codes used to regulate nonmedical electronic radiation-emitting products. The scope of the guidance document includes devices described in the existing classification under parts 862 through 892. It also describes how classification product codes are used for CBER regulated devices, which currently do not fall within this existing classification. This guidance may be applicable to future devices. It also covers unclassified devices and devices not yet classified. In the Federal Register of January 3, 2012 (77 FR 125), FDA announced the availability of the draft guidance document. Interested persons were invited to comment by May 2, 2012. Five comments were received with multiple recommendations pertaining to the administrative processes and policies regarding medical device classification product codes. In response to these comments, FDA revised the guidance document to clarify the processes and policies as appropriate. II. Significance of Guidance This guidance is being issued consistent with FDA's good guidance practices regulation (21 CFR 10.115

Overwhelmingly, workshop participants agreed that customers lack an awareness that cybersecurity capabilities can vary among devices when they make purchasing decisions about IoT. This appears to be true regardless of whether the customers are individual consumers or those responsible for procurement in organizational environments. In the consumer space the buyer's assumption generally is that if a product is on the market, its safety and security can be assumed. A UK study found that consumers focus on IoT device features and costs as the most important discriminators, with cybersecurity either not on the list of customer priorities or at best lagging far behind as a decision criterion. Mike Bergman of the Consumer Technology Association (CTA) stated that 'we have been doing this research for years and years and the answers never changed. Cybersecurity is not on this list. So while it might be a good idea to try to get it on the list · it is going to be a very

long and expensive education process.' Where meaningful cybersecurity information about a product is available, a further challenge is educating customers about how to understand the information available and interpret its implications when using the product in their environments. In organizational procurement environments, the staff responsible for procurement contracts typically lack subject matter expertise regarding cybersecurity and need education and training in leveraging contractual language to mandate security for procurements. Peter Stephens said 'whenever I speak to procurement organizations, whether they are retailers or housing, manufacturing, builders or other organizations who use smart devices in some format, the person responsible for procuring the devices quite often is not an expert at all.' The availability of sample procurement language can be of great benefit in improving the security of products procured by organizations.

(C) Exempt portions of this system also contain information considered relevant and necessary to make a determination as to qualifications, eligibility, or suitability for Federal civilian employment, military service, Federal contracts, or access to classified information, and was obtained by providing an express or implied assurance to the source that his or her identity would not be revealed to the subject of the record. (D) The notice of this system of records published in the Federal Register sets forth the basic statutory or related authority for maintenance of the system. (E) The categories of sources of records in this system have been published in the Federal Register in broad generic terms. The identity of specific sources, however, must be withheld in order to protect the confidentiality of the source, of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) This system of records is exempted from procedures for notice to an individual as to the existence of records pertaining to him/her dealing with an actual or potential civil or regulatory investigation, because such notice to an individual would be detrimental to the successful conduct and/or completion of an investigation, pending or future. Mere notice of the fact of an investigation could inform the subject or others that their activities are under, or may become the subject of, an investigation. This could enable the subjects to avoid detection, to influence witnesses improperly, to destroy records, or to fabricate testimony. (G) Exempt portions of this system containing screening board reports. (H) Screening board reports set forth the results of oral examination of applicants for a position as a special agent with the Naval Investigation Service Command. Disclosure of these records would reveal the areas pursued in the course of the examination and thus adversely affect the result of the selection process. Equally important, the records contain the candid views of the members composing the board. Release of the records could affect the willingness of the members to provide candid opinions and thus diminish the effectiveness of a program which is essential to maintaining the high standards of the Special Agent Corps., i.e., those records constituting examination material used solely to determine individual qualifications for appointment in the Federal Service. (14) System identifier and name. N05520-5, Personnel Security Program Management Records System. (i) Exemptions. (A) Information specifically authorized to be classified under E.O. 12958, as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5)

title that reflects their duties, and they may lack sufficient professional skills (e.g., communications, relationship-building) that are viewed as essential in security awareness roles [SANS][WOELK]. In addition, the lack of understanding that security awareness is a unique discipline may lead to ill-prepared awareness professionals [BADA]. However, it is unclear if these challenges also apply to security awareness professionals in the United States (U.S.) government.

.....12 | | Table 6. Availability Impact Scoring
Evaluation12 | | Table 7.
General Exploit Level Scoring
Evaluation.....13 | | Table 8.
General Remediation Level Scoring Evaluation
.....14 | | Table 9. Local Vulnerability
Prevalence Scoring Evaluation.....15 | | Table 10.
Perceived Target Value Scoring Evaluation
.....15 | | Table 11. Local Remediation
Level Scoring Evaluation.....16 | | Table

12. Collateral Damage Potential Scoring Evaluation17 | | Table 13. Confidentiality, Integrity, and Availability Requirements Scoring Evaluation18 | | Table 14. Base, Temporal, and Environmental Vectors18 |

flour from five different companies rather than depend on a single company as its supplier. The flour from the five companies may be stored in one common silo before being used in the manufacture of the cookies. In this scenario, the manufacturer could identify, depending on the date the flour was received from each company and placed in the silo and when the silo was emptied, the various companies that were the sources of the flour. Under this situation, the information is not reasonably available to determine a single source of the flour used in a particular lot of cookies. The information reasonably available to the manufacturer would be the identity of all of the potential sources of the flour for each finished lot of cookies. However, if the manufacturer had dedicated silos for each supplier of flour, then the information would be reasonably available to the manufacturer to specify the specific source of the flour for each finished product. If we determine that additional guidance is needed, FDA will consider issuing guidance in the future to explain this requirement further. Again, FDA notes that this requirement now appears in § 1.345(b) of this final rule and has been deleted from § 1.337(a) of this final rule. (Comment 98) One comment states that manufacturers of packaging face the same issues as processors who deal with commingled ingredients. The comment explains that, during the manufacture of multiple-layer packaging products, it is common to use multiple lots of raw material within a master roll of semifinished or finished product. An example of this condition would be a paper/foil lamination where one roll of foil and three to four rolls of paper are used in the same production run. In this situation, the lot numbers of the raw materials and the lot numbers of the finished products may be known, but it cannot be determined with precision which lot of the input materials is in an individual roll of finished product. (Response) Manufacturers of packaging (the outer packaging of food that bears the label and does not contact the food) are excluded from all requirements of subpart J of this final rule unless such persons also manufacture, process, pack, transport, distribute, receive, hold or import food in the United States, in which case they are subject to §§ 1.361 and 1.363 of this final rule as to the food's packaging. Manufacturers of food contact substances, whether or not the substances are the finished container that directly contacts the food, are excluded from all of the requirements of subpart J, except §§ 1.361 and 1.363 of this final rule. Therefore, such manufacturers are not required to know which lot of the input materials is in an individual roll of finished product.

This publication provides guidance to organizations on identifying, assessing, and mitigating cybersecurity risks throughout the supply chain at all levels of their organizations. The publication integrates cybersecurity supply chain risk management (C-SCRM) into risk management activities by applying a multilevel, C-SCRM-specific approach, including guidance on the development of C-SCRM strategy implementation plans, C-SCRM policies, C-SCRM plans, and risk assessments for products and services. acquire; C-SCRM; cybersecurity supply chain; cybersecurity supply chain risk management; information and communication technology; risk management; supplier; supply chain; supply chain risk assessment; supply chain assurance; supply chain risk; supply chain security. |

3.4.3. Enhancing Practices.....
.....49 | |-----

-|-----
---| 3.5.1. Measuring C-SCRM Through Performance
Measures.....52 | | References.....
.....
.....57 | | Appendix A. C-SCRM Security Controls.....
.....

the Department believes that it is essential to propose modifications to strengthen its protections for the confidentiality, integrity, and availability of ePHI to address the changing health care environment. We also believe it is important to clarify the obligations of regulated entities and emphasize the importance of protecting the confidentiality, integrity, and availability of ePHI. We believe that the proposed revisions would require regulated entities to consider and potentially modify their safeguards more regularly, which would better enable them to quickly respond to changes in the environment and be consistent with cybersecurity best practices. While we do not expect that

compliance with the Security Rule will (printed page 920) prevent all breaches or interruptions in the confidentiality, integrity, or availability of ePHI, we believe that it will prevent many and enable regulated entities to identify, mitigate, and remediate the damage more quickly if there is a breach or other security incident, thereby reducing harm to individuals and the overall costs of such occurrences to regulated entities and to the U.S. health care system. As such, the proposed modifications would support a primary goal of HIPAA's Administrative Simplification provisions: improving the efficiency and effectiveness of the U.S. health care system by encouraging the development of health information systems through the establishment of uniform standards and requirements for electronic transmission of ePHI, including those for security. [316] E. The Secretary Must Develop Standards for the Security of ePHI Because None Have Been Developed by an ANSI-Accredited Standard Setting Organization HIPAA requires the Secretary to adopt standards that have been developed, adopted, or modified by a standard setting organization accredited by ANSI, except in certain circumstances. [317] For example, HIPAA permits the Secretary to develop standards where no relevant standards have been developed, adopted, or modified by an ANSI-accredited standard setting organization. In developing, adopting, or modifying a standard, the Secretary is required to consult with standard setting organizations, NCVHS, and with the appropriate Federal and State agencies. [318] The statutory definition of the term "standard" applies only to standards for electronic transactions and data elements for such transactions that are appropriate for: (1) the financial and administrative transactions described in the statute; and (2) other financial and administrative transactions consistent with the goals of improving the operation of the health care system and reducing administrative costs, as determined appropriate by the Secretary. [319] Under HIPAA, security is not considered a financial or administrative transaction, or a data element of such transaction. [320]

(D) From subsection (e)(2) because collecting information to the fullest extent possible directly from the subject individual may or may not be practical in a criminal and/or civil investigation. (E) From subsection (e)(3) because supplying an individual with a form containing a Privacy Act Statement would tend to inhibit cooperation by many individuals involved in a criminal and/or civil investigation. The effect would be somewhat adverse to established investigative methods and techniques. (F) From subsection (e)(4) (G) through (I) because this system of records is exempt from the access provisions of subsection (d). (G) From subsection (e)(5) because the requirement that records be maintained with attention to accuracy, relevance, timeliness, and completeness would unfairly hamper the investigative process. It is the nature of law enforcement for investigations to uncover the commission of illegal acts at diverse stages. It is frequently impossible to determine initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. (H) From subsection (e)(8) because the notice requirements of this provision could present a serious impediment to law enforcement by revealing investigative techniques, procedures, and existence of confidential investigations. (I) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to that individual, and record amendment procedures for this record system. (J) For comparability with the exemption claimed from subsection (f), the civil remedies provisions of subsection (g) must be suspended for this record system. Because of the nature of criminal investigations, standards of accuracy, relevance, timeliness, and completeness cannot apply to this record system. Information gathered in an investigation is often fragmentary and leads relating to an individual in the context of one investigation may instead pertain to a second investigation. (3) System identifier and name. CIG-15, Departmental Inquiries Case System. (i) Exemption. Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2)

or (v) improve personnel skills, expertise, and understanding. Appendix E provides three tables that identify specific assurance-related controls that are included in the low-, moderate-, and high-impact baselines described in Appendix D. The controls described assist organizations in defining the controls needed to satisfy minimum assurance requirements. Where additional assurance is desired to achieve risk management objectives, Table E-4 provides additional security controls and control enhancements to achieve enhanced assurance.

(Response) Farms are excluded from these regulations, as are foreign persons, except for foreign persons who transport food in the United States. Therefore, foreign farmers who ship live food animals to the United States are exempt from this final rule (unless they transport the animals into the United States themselves). FDA notes, however, that although foreign exporters of food into the United States are exempt from these recordkeeping requirements, they must comply with the prior notice regulations issued under the Bioterrorism Act (part 1, subpart I). FDA also notes that an importer of live food animals into the United States would be required to establish and maintain records under these regulations given (printed page 71575) that importers are not exempt from this final rule. (Comment 36) One comment states that, although the proposed rule exempts farms, it may still result in a recordkeeping burden for them. The comment states that, in practice, the farmer will be expected to generate paperwork so that those delivering and dropping products off at the farm will be able to comply with the final rule. Although farms may be exempt on the face of the rule, the comment states that, in reality, farmers will have to generate large amounts of paperwork for their suppliers, truckers, and buyers. The comment states that the final rule needs to make clear that farmers will not be responsible, or expected to generate, paperwork for those complying with this rule. (Response) Farms are specifically exempted from the requirements of these regulations. Only those persons subject to these regulations must establish and maintain records of the immediate previous sources and immediate subsequent recipients of food that they manufacture, process, pack, transport, distribute, receive, hold, or import. This final rule does not require a farm to establish or maintain records for those who are subject to this regulation. 3. Restaurants (Comment 37) Several comments state that retail food stores offer a variety of services and conveniences to consumers, including foods that are prepared in-store and ready for immediate consumption, and that the restaurant-type facilities in the retail store should be excluded from the recordkeeping requirements.

The aggregate loss of intellectual property and CUI from the DoD supply chain severely undercuts U.S. technical advantage, limits and disrupts business opportunities associated with technological superiority, and ultimately threatens our national defenses and economy. By incorporating heightened cybersecurity into acquisition programs, the CMMC Program provides the Department assurance that contractors and subcontractors are meeting DoD's cybersecurity requirements and provides a key mechanism to adapt to an evolving threat landscape. This is critically important to the Department because defense contractors are the target of increasingly frequent and complex cyberattacks by adversaries and non-state actors. Dynamically enhancing DIB cybersecurity to meet these evolving threats and safeguarding the information that supports and enables our warfighters is a top priority for the Department. The CMMC Program is a key component of the Department's DIB cybersecurity effort. CMMC provides uniform and improved DoD cybersecurity requirements in three (3) levels, using the security requirements in NIST SP 800-171 R2 and a selected subset of those in NIST SP 800-172 Feb2021. With this rule, the Department is publishing supplemental guidance documents to assist the public and in particular, small businesses, with CMMC implementation, increasing the likelihood of successful implementation and strengthening cybersecurity across the DIB. CMMC decreases the burden and cost on companies protecting FCI by allowing all companies at Level 1, and a subset of companies at Level 2, to demonstrate compliance through self-assessments. CMMC allows companies, under certain limited circumstances, to make a Plan of Action & Milestones (POA&M) to provide additional time to achieve a Final CMMC Status. These key updates to CMMC benefit the DoD and our national interest by providing: improved safeguarding of competitive advantages through requirements flow-down to the defense contractor supply chain and protections for proprietary information and capabilities, and increased efficiency in the economy and private markets as a result of the streamlining of cybersecurity requirements, the resulting improvements in cybersecurity, and accountability across the supply chain.

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: McKeown Performing the Duties of the Deputy DoD CIO for Cybersecurity and DoD Chief Information Security Officer Attachment: As stated Attachment A: NIST SP 800-171 Revision 3 ODP Values Access Control 3.1.1 System Account Management a. Define the types of system accounts allowed and prohibited. b. Create, enable, modify, disable, and remove system accounts in accordance with policy, procedures, prerequisites, and criteria. c. Specify: 1. Authorized users of the system, 2. Group and role membership, and 3. Access authorizations (i.e., privileges) for each account. d. Authorize access to the system based on: 1. A valid access authorization and 2. Intended system usage. e. Monitor the use of system accounts. f. Disable system accounts when: 1. The accounts have expired,

During the processing of a Privacy Act request (which may include access requests, amendment requests, and requests for review for initial denials of such requests), exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those 'other' systems of records are entered into this system, the Office of the Secretary of Defense hereby claims the same exemptions for the records from those 'other' systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (printed page 14806) (14) System identifier and name. DHRA 02, PERSEREC Research Files. (i) Exemption. (A) Investigative material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (B) Therefore, portions of this system may be exempt pursuant to 5 U.S.C. 552a(k) (5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), and (e)(1). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons.

(g) Certain commercial items and initial provisioning spares for weapons systems are requested and subsequently solicited using units of measure such as kit, set, or lot. However, there are times when individual items within that kit, set, or lot are not grouped and delivered in a single shipment. This creates potential contract administration issues with inspection, acceptance, and payment. In such cases, solicitations should be structured to allow offerors to provide information about products that may not have been known to the Government prior to solicitation and propose an alternate line item structure as long as the alternate is consistent with the requirements of 204.71, which provides explicit guidance on the use of contract line items and subline items, and with PGI 204.71. 3. Revise section 204.7109 to read as follows: 204.7109 Solicitation provision and contract clause. (a) Use the clause at 252.204-7006, Billing Instructions, in solicitations and contracts if Section G includes- (1) Any of the standard payment instructions at PGI 204.7108(d)(1) through (6); or (2) Other payment instructions, in accordance with PGI 204.7108(d)(12), that require contractor identification of the contract line item(s) on the payment request. (b) Use the provision at 252.204-7011, Alternative Line Item Structure, in solicitations for commercial items and initial provisioning spares. PART 212-ACQUISITION OF COMMERCIAL ITEMS 4. Amend section 212.301 by revising paragraph (f)(iv) to read as follows: 212.301 Solicitation provisions and contract clauses for the acquisition of commercial items. (f) * * * (iv) Use the provisions and clauses prescribed elsewhere in DFARS as follows: (A) Use the provision at 252.204-7011, Alternative Line Item Structure, as prescribed in 204.7109(b). (B) Use the provision at 252.209-7001, Disclosure of Ownership or Control by the Government of a Terrorist Country, as prescribed in 209.104-70(a). (C) Use the clause at 252.211-7003, Item Identification and Valuation, as prescribed in 211.274-4. (D) Use the clause at 252.211-7006, Radio Frequency Identification, as prescribed in 211.275-3. (E) Use the provision at 252.225-7010, Commercial Derivative Military Article-Specialty Metals Compliance Certificate, as prescribed in 225.7003-5(b). (F) Use the clause at 252.225-7040, Contractor Personnel Authorized to Accompany U.S. Armed Forces Deployed Outside the United States, as prescribed in 225.7402-4. (G) Use the clause at 252.225-7043, Antiterrorism/Force Protection Policy for Defense Contractors Outside the United States, in solicitations and contracts that include the clause at 252.225-7040. (H) Use the clause at 252.232-7009, Mandatory Payment by Governmentwide Commercial Purchase Card, as prescribed in 232.1110. (I) Use the clause at 252.232-7010, Levies on Contract Payments, as prescribed in 232.7102. (J) Use the clause at 252.232-7011, Payments in Support of Emergencies and Contingency Operations, as prescribed in

3.2.4 | Evaluation of Potential Consequences... 3.2.4 Evaluation of Potential Consequences The final component of risk identification is documenting the potential consequences of each risk listed in the register. 3.2.4, the practitioner can create a set of risk scenarios (described at the beginning of Section 3) in the risk description column of the Cybersecurity Risk Register (CSRR), including the source of uncertainty, predisposing conditions, resources affected, and anticipated result.

- Section 2 describes the need for effective recovery planning in advance of a cyber event. The section provides information about improving enterprise resiliency, recovery processes and procedures, recovery communications, and insight sharing. - Section 3 provides guidance for achieving continuous improvement of the organization's recovery processes and security posture. It emphasizes the need to validate recovery capabilities using a variety of techniques, including asking personnel for feedback on recovery plans, policies, and procedures, and periodically conducting exercises and tests that address real-world recovery. - Section 4 gives examples of recovery metrics that may help organizations to measure and monitor their recovery performance over time. - Section 5 summarizes the recommendations introduced in earlier sections to develop a recovery playbook which is composed of tactical and strategic phases. - Section 6 provides an example of a data breach cyber event recovery scenario that demonstrates the application of guidance in earlier sections. - Section 7 presents a second example covering a ransomware event recovery scenario. - Appendix A-includes a checklist of recovery actions. - Appendix B-provides mappings from the recovery processes and activities to the Cybersecurity Framework and related NIST SP 800-53 security controls. - Appendix C-provides a list of acronyms and abbreviations that appear in the document. - Appendix D-includes a list of references that provide additional information for the reader. Effective planning is a critical component of an organization's preparedness for cyber event recovery. As part of an ongoing organizational information security program, recovery planning enables participants to understand system dependencies; critical personnel identities such as crisis management and incident management roles; arrangements for alternate communication channels, services, and facilities; and many other elements of business continuity.

This rule does not require any specific reporting, recordkeeping or compliance requirements. It does, however, recognize the need for information technology contractors to implement appropriate safeguards and countermeasures to minimize supply chain risk. This rule, by itself, does not require contractors to deploy additional supply chain risk protections, but leaves it up to the individual contractors to take the steps they think are necessary to maintain existing or otherwise required safeguards and countermeasures as necessary for their own particular industrial methods to protect their supply chain. The rule does not duplicate, overlap, or conflict with any other Federal rules. Consistent with the stated objectives of section 806 and the DoDI, no viable alternatives exist. Possible alternatives considered included having all contractors report, on all contracts, the nature of the supply chain risk mitigation efforts they have applied to their manufacturing processes. This would be unduly burdensome for both contractors and the Government. Another alternative is not to have section 806 clauses apply to commercial and COTS items or purchases below the simplified acquisition threshold. However, the requirements of section 806 should apply to contracts and subcontracts at or below the simplified acquisition threshold because the malicious introduction of unwanted functions may occur at any dollar threshold. Therefore, it would not be in the best interest of the Federal Government to exempt contracts and subcontracts at or below the simplified acquisition threshold from this requirement. In a like manner, the requirements of section 806 should apply to the procurement of commercial items (including COTS items) because the intent of the statute is to protect the supply chain which in turn protects all NSS. Commercial and COTS information technology supplies and services often become part of NSSs. Protection of the NSSs using the authority of section 806 requires application in all information technology supply and services contracts. Therefore, exempting commercial (including COTS) items from application of the statute would negate the intended effect of the statute. DoD invites comments from small business concerns and other interested parties on the expected impact of this rule on small entities. DoD will also consider comments from small entities concerning the existing regulations in subparts affected by this rule in accordance with 5 U.S.C. 610 . Interested parties must submit such comments separately and should cite 5 U.S.C. 610 (DFARS Case 2012-D050) in correspondence. V. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the (printed page 69270)

a. CMMC Cost Assumptions and Estimates Comment: Several commenters questioned or refuted the cost estimates and/or the assumptions and mathematical approach upon which the cost estimates were based. Several commenters requested clarification around the cited difference in both cost and hours between the CMMC certification process and the DoD Assessment process, the accounting for completion of NIST SP 800-171 Rev 2 requirements, and cost distinction between enterprise and enclave assessments. Two commenters stated that the estimated number of subcontractors was low, and one commenter suggested that the \$5 million threshold for small businesses excluded a large number of small businesses from the calculations. One commenter asked whether duplication of assessments was considered for small businesses who support many prime contractors. Additional commenters believed costs were absent from the calculations, to include the cost of completing POA&M, management costs for small companies to achieve maturity, and costs for international suppliers. A number of comments requested additional estimates based on adjustments to labor rates for benefits and taxes, each of the assessment levels, and small, medium, and large companies. One commenter asked for clarification on the calculations used to estimate public savings. One commenter questioned why North American Industry Classification System (NAICS) code 54715 pertaining to sensitive CUI was not included in the calculations. Response:

stomize assessments based on organizational policies and requirements, known threat and vulnerability information, system and platform dependencies, operational considerations, and tolerance for risk. 1 | Access Control | Maintenance | Security Assessment and Monitoring |

|-----|-----|-----| |
Awareness and Training | Media Protection | System and Communications Protection | | Audit and Accountability | Personnel Security | System and Information Integrity | | Configuration Management | Physical Protection | Planning | | Identification and Authentication | Risk Assessment | System and Services Acquisition | | Incident Response | | Supply Chain Risk Management |

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: MCKEOWN.DA VID.W.1034948 Digitally signed by MCKEOWN.DAVID.W.1034 948050 Date: 2025.04.10 14:34:00 -04'00' David W. McKeown Performing the Duties of the Deputy DoD CIO for Cybersecurity and DoD Chief Information Security Officer Attachment: As stated

Using the terms of the ISO/IEC 17020:2012(E), the activity of the C3PAO is an inspection, rather than a certification. The C3PAO is an inspection body, not a certification body, and is responsible for conducting the Level 2 certification assessment [Inspection]. The rule was revised to delete terms related to granting or revoking certification assessment status. The DoD reserves the right to conduct a DCMA DIBCAC assessment of the OSA, as provided for under the DFARS clause 252.204-7012 and DFARS clause 252.204-7020. DoD declines to extend the period for C3PAOs to achieve compliance with ISO/IEC 17020:2012(E). The Department has determined that 27 months is reasonable and sufficient for a C3PAO to achieve compliance. The rule was also updated in § 170.9(b)(11) to clarify that audit information must be provided upon request. 14. Ecosystem Capacity Comment: Commenters expressed concern that the demand for third-party assessments amongst the defense industrial base will exceed the capacity of available Certified CMMC Assessors and Certified CMMC Professionals and government assessors which may prevent timely and affordable audits or cause businesses to lose out on DoD contracts. To mitigate the concerns, one commenter suggested delaying phase-in of certification assessment by two years, by relying on self-assessment. One commenter warned of solicitation protests if companies are kept out of a competitive procurement due to a slow CMMC assessment process. Another suggested that insufficient assessors may shrink the market for DoD contractors and compromise assessment quality. Commenters were apprehensive that DoD projections for certification demand didn't factor in all subcontractors and that the CMMC Accreditation Body lacks a strategy for scaling to meet increased C3PAO demand. Additionally, one commenter pointed out that the rule indicates companies can pursue a certification assessment at any time after the rule is published, which could tie up already limited C3PAO resources and impede assessment opportunities for other companies bidding on an upcoming contract. Another expressed concern that often-extensive travel times required for assessors to reach rural-based companies like electric cooperatives will disincentivize assessors from prioritizing these companies and prevent their timely assessment.

884. See Post-Quantum Cryptography PQC, supra note 882. Back to Citation 885. Id. Back to Citation 886. See id. (removed emphasis from post-quantum cryptography in original).

Back to Citation 887. ·National Security Memorandum on Promoting United States Leadership in Quantum Computing While Mitigating Risks to Vulnerable Cryptographic Systems, National Security Memorandum/NSM-10, The White House (May 4, 2022), <https://www.whitehouse.gov/briefing-room/statements-releases/2022/05/04/national-security-memorandum-on-promoting-united-states-leadership-in-quantum-computing-while-mitigating-risks-to-vulnerable-cryptographic-systems/> .

Back to Citation 888. Id. Back to Citation 889. · See Letter from NCVHS Chair Jacki Monson (2023), *supra* note 123, Appendix p. 2 (providing NCVHS recommendations to strengthen the HIPAA Security Rule). Back to Citation 890. · See ·Quantum-Readiness: Migration to Post-Quantum Cryptography,· Cybersecurity & Infrastructure Security Agency, National Security Agency, and National Institute of Standards and Technology, p. 1 (Aug. 21, 2023), <https://media.defense.gov/2023/Aug/21/2003284212/-1/-1/0/CSI-QUANTUM-READINESS.PDF> . Back to Citation 891. Id. Back to Citation 892. ·Sec. 238(g) of Public Law 115-232 , 132 Stat. 1697-98 (Aug. 13, 2018) (10 U.S.C. 2358 note) (definition of ·AI·). Back to Citation 893. ·Kathryn Marchesini, et al., ·Getting the Best out of Algorithms in Health Care,· HealthITbuzz, Assistant Secretary for Technology Policy, U.S. Department of Health and Human Services (June 15, 2022), <https://www.healthit.gov/buzz-blog/electronic-health-and-medical-records/getting-the-best-out-of-algorithms-in-health-care> . Back to Citation 894. · See Nazish Khalid, et al., ·Privacy-preserving artificial intelligence in healthcare: Techniques and applications,· Computers in Biology and Medicine, Volume 158, p. 1 (May 2023), https://www.sciencedirect.com/science/article/pii/S001048252300313X?ref=pdf_download&fr=RR-2&rr=8a7dac430d6d07d5 . Back to Citation 895. · See ·Artificial Intelligence Program: Research on AI/[Machine Learning] ML-Based Medical Devices,· U.S. Food & Drug Administration, U.S. Department of Health and Human Services (June 10, 2024), <https://www.fda.gov/medical-devices/medical-device-regulatory-science-research-programs-conducted-osel/artificial-intelligence-program-research-aiml-based-medical-devices> .

Back to Citation 896. Id. Back to Citation 897. · See Michael D. Howell, et al., ·Three Epochs of Artificial Intelligence in Health Care,· Journal of the American Medical Association, Volume 331, Number 3 (Jan. 16, 2024), <https://jamanetwork.com/journals/jama/fullarticle/2813874> . Back to Citation 898. · See Aaron A. Tierney, et al., ·Ambient Artificial Intelligence Scribes to Alleviate the Burden of Clinical Documentation,· New England Journal of Medicine Catalyst (Feb. 21, 2024), <https://catalyst.nejm.org/doi/full/10.1056/CAT.23.0404> . Back to Citation 899. Id.

usage) to home IoT devices may result in increased costs, design changes, or have an impact on functionality. Mark Haney gave an example of having to charge a smart watch battery daily versus weekly. Panelist Andrew Tierney gave another example using multi-factor authentication (MFA): 'MFA represents a massive security improvement and stops password phishing. However, because consumers don't want barriers, some companies are hurt by deploying MFA. Consumers will go elsewhere.' These examples illustrate what can occur when

2 3.1.11 33 Review DoD Cybersecurity FAQ Q53.2 for information on minimum values. AC.L2-3.1.12 · Control Remote Access CMMC Assessment Guide · Level 2 | Version 2.13 40 AC.L2-3.1.12 · CONTROL REMOTE ACCESS Monitor and control remote access sessions. ASSESSMENT OBJECTIVES [NIST SP 800-171A]34 Determine if: [a] remote access sessions are permitted; [b] the types of permitted remote access are identified; [c] remote access sessions are controlled; and [d] remote access sessions are monitored. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]34 Examine [SELECT FROM: Access control policy; procedures addressing remote access implementation and usage (including restrictions); configuration management plan; system security plan; system design documentation; system configuration settings and associated documentation; remote access authorizations; system audit logs and records; other relevant documents or records]. Interview [SELECT FROM: Personnel with responsibilities for managing remote access connections; system or network administrators; personnel with information security responsibilities]. Test [SELECT FROM: Remote access management capability for the system]. DISCUSSION [NIST SP 800-171 REV. 2]35 Remote access is access to organizational systems by users (or processes acting on behalf of users) communicating through external networks (e.g., the internet). Remote access methods include dial-up, broadband, and wireless. Organizations often employ encrypted virtual private networks (VPNs) to enhance confidentiality over remote connections. The use of encrypted VPNs does not make the access non- remote; however, the use of VPNs, when adequately provisioned with appropriate control (e.g., employing encryption techniques for confidentiality protection), may provide sufficient assurance to the organization that it can effectively treat such connections as internal networks. VPNs with encrypted tunnels can affect the capability to adequately monitor network communications

traffic for malicious code. 34 NIST SP 800-171A, p. 14. 35 NIST SP 800-171 Rev. 2, pp. 13-14.

(ii) Future classified negotiations may occur within 12 months. (iii) There is reasonable likelihood the subcontractor may be awarded a classified subcontract. (iv) Subcontracting that involves access to FGI. (A) A U.S. contractor may award a subcontract that involves access to FGI to another U.S. contractor after verifying with the CSA that the prospective subcontractor has the appropriate entity eligibility determination and a classified information storage capability, and review of the prime contract to determine if there are any contractual limitations for approval before awarding a subcontract. The contractor awarding a subcontract will provide appropriate security classification guidance and incorporate the pertinent security provisions in the subcontract. (B) The contractor cannot award subcontracts involving FGI to a contractor in a third country or to a U.S. entity with a limited entity eligibility determination based on third-country FOCI without the express written consent of the originating foreign government. The CSA will coordinate with the appropriate foreign government authorities. (b) Security classification guidance. (1) Prime contractors will ensure that a Contract Security Classification Specification, or equivalent, is incorporated in each classified subcontract. (i) When preparing classification guidance for a subcontract, the prime contractor may extract pertinent information from: (A) The Contract Security Classification Specification, or equivalent, issued with the prime contract. (B) Security classification guides issued with the prime contract. (C) Any security guides that provide guidance for the classified information furnished to, or that will be generated by, the subcontractor. (ii) The Contract Security Classification Specification, or equivalent, prepared by the prime contractor will be certified by a designated official of the contractor. (iii) In the absence of exceptional circumstances, the classification specification will not contain any classified information. If classified supplements are required as part of the Contract Security Classification Specification, or equivalent, they will be identified and forwarded to the subcontractor by separate correspondence. (2) An original Contract Security Classification Specification, or equivalent, will be included with each RFQ, RFP, IFB, or other solicitation to ensure that the prospective subcontractor is aware of the security requirements of the subcontract and can plan accordingly. An original Contract Security Classification Specification, or equivalent, will also be included in the subcontract awarded to the successful bidder. (3) A revised Contract Security Classification Specification, or equivalent, will be issued as necessary during the lifetime of the subcontract when the security requirements change. (4) Requests for public release by a subcontractor will be forwarded through the prime contractor to the GCA. (printed page 83347) (c)

Cyber incident means actions taken through the use of computer networks that result in an actual or potentially adverse effect on an information system and/or the information residing therein. (f) Cyber intrusion damage assessment means a managed, coordinated process to determine the effect on defense programs, defense scientific and research projects, or defense warfighting capabilities resulting from compromise of a DIB participant's unclassified computer system or network. (g) Defense Industrial Base (DIB) means the Department of Defense, Government, and private sector worldwide industrial complex with capabilities to perform research and development, design, produce, and maintain military weapon systems, subsystems, components, or parts to satisfy military requirements. (h) DIB participant means a DIB company that has met all of the eligibility requirements to participate in the voluntary DIB CS/IA information sharing program as set forth in this part (see § 236.7). (i) Government means the United States Government. (j) Government Furnished Information (GFI) means information provided by the Government under the voluntary DIB CS/IA program, including but not limited to cyber threat information and information assurance practices. (k) Information means any communication or representation of knowledge such as facts, data, or (printed page 62436) opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, or audiovisual. (l) Information system means a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information. (m) Threat means any circumstance or event with the potential to adversely impact organization operations (including mission, functions, image, or reputation), organization assets, individuals, other organizations, or the Nation through an information system via unauthorized access, destruction, disclosure, modification of information and/or denial of service. (n) U.S. based means provisioned, maintained, or operated within the physical boundaries of the United States. (o) U.S. citizen means a person born in the United States or naturalized. § 236.3 Policy. It is DoD policy to: (a) Establish a comprehensive approach for enhancing and supplementing DIB information assurance capabilities to safeguard covered

defense information on covered DIB systems. (b) Increase the Government and DIB situational awareness of the extent and severity of cyber threats to DoD information. § 236.4 Procedures. (a) The Government and each DIB participant will execute a voluntary standardized agreement, referred to as a Framework Agreement (FA), to share, in a timely and secure manner, on a recurring basis, and to the greatest extent possible, cyber security information relating to information assurance for covered defense information on covered DIB systems.

From the NIST SP 800-172 Rev 3 Final Public Draft: Summary of Enhanced Security Requirements 3120
This appendix provides a consolidated list of the enhanced security requirements in Sec. 3. The type of enhanced security requirement is indicated in the last column of Table 2. · A designation of ·E· indicates that the security requirement enhances a requirement in SP 800-171 [12] and includes AP 800-171 requirement. · A designation of ·T· indicates that the security requirement is sourced to a control tailored out of the SP 800-53B [13] moderate baseline in SP 800-171 and includes the SP 800-53 control. · A designation of ·S· indicates that the security requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. It inc

Document or reference in the system security plan the security solution selected, the rationale for the security solution, and the risk determination. (xvii) RA.L3-3.11.5e Assess the effectiveness of security solutions at least annually or upon receipt of relevant cyber threat information, or in response to a relevant cyber incident, to address anticipated risk to organizational systems and the organization based on current and accumulated threat intelligence. (xviii) RA.L3-3.11.6e Assess, respond to, and monitor supply chain risks associated with organizational systems and system components. (xix) RA.L3-3.11.7e Develop a plan for managing supply chain risks associated with organizational systems and system components; update the plan at least annually, and upon receipt of relevant cyber threat information, or in response to a relevant cyber incident. (xx) CA.L3-3.12.1e Conduct penetration testing at least annually or when significant security changes are made to the system, leveraging automated scanning tools and ad hoc tests using subject matter experts. (xxi) SC.L3-3.13.4e Employ physical isolation techniques or logical isolation techniques or both in organizational systems and system components. (printed page 89129) (xxii) SI.L3-3.14.1e Verify the integrity of security critical and essential software using root of trust mechanisms or cryptographic signatures. (xxiii) SI.L3-3.14.3e Ensure that Specialized Assets including IoT, IIoT, OT, GFE, Restricted Information Systems, and test equipment are included in the scope of the specified enhanced security requirements or are segregated in purpose-specific networks. (xxiv) SI.L3-3.14.6e Use threat indicator information and effective mitigations obtained from, at a minimum, open or commercial sources, and any DoD-provided sources, to guide and inform intrusion detection and threat hunting. 1 Roman numerals in parentheses before the Security Requirement are for numbering purposes only. The numerals are not part of the naming convention for the requirement. (d) Implementation. Assessment of security requirements is prescribed by NIST SP 800-171A (incorporated by reference, see § 170.2) and NIST SP 800-172A (incorporated by reference, see § 170.2). Descriptive text in these documents support OSA implementation of the security requirements and use the terms organization-defined and periodically. Except where referring to an Organization-Defined Parameter (ODP), organization-defined means as determined by the OSA being assessed. Periodically means occurring at regular intervals. As used in many requirements within CMMC, the interval length is organization-defined to provided contractor flexibility, with an interval length of no more than one year. § 170.15 CMMC Level 1 Self-Assessment and Affirmation requirements. (a) CMMC Level 1 Self-Assessment. To comply with CMMC Level 1 requirements, the OSA must meet the requirements detailed in paragraphs (a)(1) and (2) of this section. (1) Self-Assessment.

(iii) On a tear-off sheet attached to the form; or (iv) As a separate supplement to the form. (b) Forms issued by non-DoD activities. (1) Forms subject to the Privacy Act issued by other Federal Agencies must have a Privacy Act Statement. Always ensure the statement prepared by the originating Agency is adequate for the purpose for which the form shall be used by the DoD activity. If the Privacy Act Statement provided is inadequate, the DoD Component concerned shall prepare a new statement or a supplement to the existing statement before using the form. (2) Forms issued by agencies not subject to the Privacy Act (State, municipal, and other local agencies) do not contain Privacy Act Statements. Before using a form prepared by such agencies to collect personal data subject to this part, an appropriate Privacy Act Statement must be added. Subpart D-Access by Individuals § 310.17 Individual access to personal information. (a) Individual access. (1) The

access provisions of this part are intended for use by individuals who seek access to records about themselves that are maintained in a system of records. Release of personal information to individuals under this part is not considered public release of the information. (2) Make available to the individual to whom the record pertains all of the personal information contained in the system of records except where access may be denied pursuant to an exemption claimed for the system (see subpart F to this part). However, when the access provisions of this subpart are not available to the individual due to a claimed exemption, the request shall be processed to provide information that is disclosable pursuant to the DoD Freedom of Information Act program (see 32 CFR , part 286). (b) Individual requests for access. Individuals shall address requests for access to personal information in a system of records to the system manager or to the office designated in the DoD Component procedural rules or the system notice. (c) Verification of identity. (1) Before granting access to personal data, an individual may be required to provide reasonable proof of his or her identity. (2) Identity verification procedures shall not: (i) Be so complicated as to discourage unnecessarily individuals from seeking access to information about themselves; or (ii) Be required of an individual seeking access to records that normally would be available under the DoD Freedom of Information Act Program (see 32 CFR , part 286). (iii) When an individual seeks personal access to records pertaining to themselves in person, proof of identity is normally provided by documents that an individual ordinarily possesses, such as employee and military identification cards, driver's license, other licenses, permits or passes used for routine identification purposes.

Conversely, if a restaurant/retail facility's sales of food it does not prepare and sell for immediate consumption are 10 percent or more of its total food sales, FDA believes that such sales are a significant portion of the facility's activities. Such a facility's retail food sales are exempt only from the requirement to establish and maintain records of sales to consumers. The restaurant/retail facility's sales of food it prepares and sells for immediate consumption remain exempt from all of the requirements of subpart J of this final rule. As noted earlier, retail facilities are required to keep records of sales to nonconsumers only to the extent that information is reasonably available. Section 306 of the Bioterrorism Act specifically exempts restaurants, but not retailers. FDA believes persons, including retailers, must establish and maintain records of immediate previous sources to ensure that FDA can quickly and effectively conduct a traceback in a food-related emergency. However, a retail food establishment that employs 10 or fewer full-time equivalent employees is excluded from all of the requirements of this final rule, except §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) (Comment 44) Several comments state that, although they make every effort to provide food to their customers in a timely and efficient manner, a small percentage of the food that is in a grocery store is sent to a reclamation center from which it is either returned to the manufacturer or sent to food banks. Reclamation centers are currently the largest single source of food donations for food banks. Food may be sent to reclamation centers if its packaging is damaged or if it is past the "best if used by" date. The system for sending food to reclamation centers is simple: The unsaleable products are collected in banana cartons and then shipped to the center where the food is sorted and either donated to charitable organizations, such as food banks, or returned to the manufacturers. No records are kept by the store of the foods shipped to the reclamation center.

The RDA protocol is designed as an interface between a local SQL server and a remote SQL processor. The use of RDA on an open network may expose the system to many threats, including eavesdropping, packet replay, and host spoofing. These threats can be minimized by employing encryption techniques and strong authentication measures. RDA has built-in facilities which allow for the exchange of authentication data.

Investigatory information compiled for law-enforcement purposes, other than information that is covered by the general exemption (see § 310.28). If an individual is denied any right, privilege or benefit he or she is otherwise entitled by Federal law or for which he or she would otherwise be eligible as a result of the maintenance of the information, the individual shall be provided access to the information except to the extent that disclosure would reveal the identity of a confidential source. This exemption provides limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (i) The information must be compiled for some investigative law enforcement purpose, such as a criminal investigation by a DoD office, whose principal function is not law enforcement, or a civil investigation. (ii) The exemption does not

apply to investigations conducted solely for the purpose of a routine background investigation (see paragraph (a)(5) of this section), but will apply if the investigation is for the purpose of investigating DoD personnel who are suspected of violating statutory or regulatory authority. (iii) The exemption can continue to be claimed even after the investigation has concluded and there is no future likelihood of further enforcement proceedings. (3) (k)(3). Records maintained in connection with providing protective services to the President and other individuals under 18 U.S.C. 3056, Powers, Authorities, and Duties of United States Secret Service. (4) (k)(4). Records maintained solely for statistical research or program evaluation purposes and that are not used to make decisions on the rights, benefits, or entitlement of an individual except for census records that may be disclosed under 13 U.S.C. 6, Information for other Federal Departments and Agencies. (5) (k)(5). Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information, but only to the extent such material would reveal the identity of a confidential source. (i) This exemption permits protection of confidential sources used in background investigations, employment inquiries, and similar inquiries that are for personnel screening to determine suitability, eligibility, or qualifications. (ii) This exemption is applicable not only to investigations conducted prior to the hiring of an employee, but it also applies to investigations conducted to determine continued employment suitability or eligibility. (printed page 18776) (6) (k)(6). Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal or military service, if the disclosure would compromise the objectivity or fairness of the test or examination process. (7) (k)(7).

- identify known and anticipated threats to the satellite ground segment and supporting infrastructure; - protect the systems that the ground segment relies on through policy, training, resilience, and access control; - detect a loss of ground segments' confidentiality, integrity, or availability; - respond to confidentiality breaches of Telemetry, Tracking, and Command (TT&C) and a manipulation or loss of satellite commands or telemetry in a timely, effective, and resilient manner; and - recover from anomalies in a timely, effective, and resilient manner. This section was created by using the Cybersecurity Framework, as described in Section 3.2. The tables summarize the Subcategories within a Category for a Function. The Informative References provide additional guidance.

minimum) level of security for each relevant electronic information system and technology asset in its relevant electronic information systems and to maintain such information systems and technology assets according to those secure baselines. Consistent with our proposals regarding risk analysis and risk management planning, the Department intends for a regulated entity to establish its security baseline and to maintain that baseline even when technology changes. For example, a regulated entity that uses software to access ePHI would be required to update the software with patches as reasonable and appropriate. But where a developer ceases to support a software, it would be reasonable and appropriate for the regulated entity to take steps to either replace it or to otherwise ensure that its level of security remains consistent with the regulated entity's established baseline. Under this proposal, if finalized, the Department would expect a regulated entity to continually monitor its relevant electronic information systems and technology assets in its relevant electronic information systems to ensure that the secure baselines established by the regulated entity are maintained and take appropriate actions when a relevant electronic information system or technology asset in a relevant electronic information system fails to meet the established baselines. A regulated entity's secure baselines would be determined based on its risk analysis and use of security settings that are consistent across its relevant electronic information systems and technology assets in its relevant electronic information systems. For example, the risk analysis may determine that a manufacturer's default settings for a particular technology asset are insufficient. Accordingly, the regulated entity may establish the baseline for settings that should be applied to the particular asset and similar technologies across the regulated entity's enterprise. This proposed standard aligns with the Department's enhanced CPG for Configuration Management, which calls for regulated entities to define secure device and system settings. It also aligns with the enhanced CPG for Detect and Respond to Relevant Threats and Tactics, Techniques, and Procedures by calling for regulated entities to include malware protection in their security baseline to detect threats and protect electronic information systems. [748] Additionally, the proposed standard also aligns with the Department's essential CPG for Email Security, which addresses the reduction of risks from email-based threats. [749] The Department proposes five implementation

specifications for the proposed standard for configuration management. [750] Under the proposed implementation specification for anti-malware protection at proposed 45 CFR 164.312(c)(2)(i)

DEPARTMENT OF ENERGY ADP SYSTEM RISK ASSESSMENT DEPARTMENT OF ENERGY ADP SYSTEM RISK ASSESSMENT	
MASTER LIST OF DOE SECURITY REQUIREMENTS STEP 3 RESOURCE TABLE R3 (Page 2) -----	
----- -----	
-- ----- -----	
----- {8} BASELINE REQUIREMENT CODE* TITLE (C) DOE DOCUMENT NUMBER** (*) g-	
PERSONNEL SECURITY PROGRAM PERSONNEL SECURITY PROGRAM DOE 5631.2B h. SAFEGUARDING OF NAVAL	
NUCLEAR PROPULSION INFORMATION SAFEGUARDING OF NAVAL NUCLEAR PROPULSION INFORMATION DOE 5630.8	
(*) i VIOLATION OF LAWS, LOSSES, INCIDENTS OF SECURITY CONCERN VIOLATION OF LAWS, LOSSES,	
INCIDENTS OF SECURITY CONCERN DOE 5631 .5 (*) j. PROTECTION PROGRAM OPERATIONS PROTECTION	
PROGRAM OPERATIONS DOE 5632.1 A k. OPERATIONS SECURITY OPERATIONS SECURITY DOE 5632.3B	
(*) 1. PHYSICAL PROTECTION OF SPECIAL NUCLEAR MATERIAL AND VITAL EQUIPMENT PHYSICAL PROTECTION	
OF SPECIAL NUCLEAR MATERIAL AND VITAL EQUIPMENT DOE 5632.2A m.	

(iii) If a company disputes a DSS determination that the company is under FOCI, or disputes the DSS determination regarding the types of actions necessary to mitigate or negate the FOCI, the company may appeal in writing those determinations to the Director, DSS, for a final agency decision no later than 30 days after receipt of written notification of the DSS decision. The company must identify the specific relief sought and grounds for that relief in its appeal. In response, the Director, DSS, may request additional information from the company. At a minimum, DSS will respond to appeals within 30 days, either with a decision or an estimate as to when a decision will be rendered. DSS will not release pre-decisional information to the company, its legal counsel, or any of its representatives without the express written approval of the applicable GCAs who own the data and any other USG entities with an interest in the company's FOCI action plan. (iv) DoD recognizes that FOCI concerns may arise in a variety of other circumstances, all of which cannot be listed in this subpart. In FOCI cases involving any foreign ownership or control, DSS will advise and consult with the appropriate GCAs, including those with special security needs, regarding the required FOCI mitigation or negation method and provide those GCAs with the details of the FOCI factors and any associated risk assessments. DSS and GCAs will meet to discuss the FOCI action plan, when determined necessary by either DSS or the applicable GCAs. When DSS determines that a company may be ineligible for an FCL by virtue of FOCI, or that additional action by the company may be necessary to mitigate the FOCI or associated risks, DSS will promptly notify the company and require it to submit a FOCI action plan to DSS within 30 calendar days of the notification. In addition, DSS will advise company management that failure to submit the requested plan within the prescribed period of time will result in termination of FCL processing or initiation of action to revoke an existing FCL, as applicable. (v) In instances where the identification of a foreign owner or voting interest of five percent or more cannot be adequately ascertained (e.g., the participating investors in a foreign investment or hedge fund, owning five percent or more of the company, cannot be identified), DSS may determine that the company is not eligible for an FCL.

example, an organization might require that laptops not be left unattended when taken to hotels, conferences, and other locations where third parties could easily gain physical access to the devices. Organizations may also have physical security requirements for papers and other non-computer media that contain sensitive information and are taken outside the organization's facilities. - - Encrypting files stored on telework devices and removable media such as CDs and flash drives. This prevents attackers from readily gaining access to information in the files. Many options exist for protecting files, including encrypting individual files or folders, volumes, and hard drives. Generally, using an encryption method to protect files also requires the use of an authentication mechanism (e.g., password) to decrypt the files when needed. - - Ensuring that information stored on telework devices is backed up. If something adverse happens to a device, such as a hardware, software, or power failure or a natural disaster, the information on the device will be lost unless it has been backed up to another device or removable media. Some organizations permit teleworkers to back up their local files to a centralized system (e.g., through VPN remote access), whereas other organizations recommend that their teleworkers perform local backups (e.g., burning CDs, copying files onto removable media). Teleworkers should perform backups, following their organizations' guidelines, and verify that the backups are valid and complete. 5 It is important that backups on removable media be secured at least as well as the device that they backed up. For

example, if a computer is stored in a locked room, then the media also should be in a secured location; if a computer stores its data encrypted, then the backups of that data should also be encrypted. - - Ensuring that information is destroyed when it is no longer needed.

Correlating audit record review, analysis, and reporting processes helps to ensure that they do not operate independently, but rather collectively. Regarding the assessment of a given organizational system, the requirement is agnostic as to whether this correlation is applied at the system level or at the organization level across all systems. FURTHER DISCUSSION Companies must review, analyze, and report audit records to help detect and respond to security incidents in a timely manner for the purpose of investigation and corrective actions. Collection of audit logs into one or more central repositories may facilitate correlated review. 70 NIST SP 800-171A, p. 23. 71 NIST SP 800-171 Rev. 2, p. 19.

One comment asked why the rule does not include requirements for LTPs, and another requested additional rule text to clarify the relationship between an ATP and the CAICO in administrative matters of students. One comment recommended not requiring CCIs to provide qualification and training information to the CAICO. One comment recommended a method for reducing a perceived redundancy in the rule text between ecosystem-related sections. Two comments asserted that a CCI certification is redundant because individuals attempting to become CCIs are already certified as CCPs or CCAs. One comment asked that a new requirement be added to the rule under § 170.12 to address the transition of Provisional Instructors to CCIs. Response: The CMMC rule does not use the term Licensed Training Provider (LTP), as training providers are not required to be licensed. The correct term for CMMC training providers is Approved Training Provider (ATP). The CMMC rule contains the requirements to create the training for the CMMC Program. § 170.10 contains the requirements for the CAICO to ensure compliance with ISO/IEC 17024:2012(E) and to ensure all training products, instruction, and testing materials are of high quality. DoD disagreed with a comment to delete a requirement in the rule for CCIs to update the CAICO regarding qualification, training experience, and other information relating to their competency to teach within the CMMC ecosystem. Viewing and verifying CCI qualifications is an important element of quality assurance in the CAICO's role of training, testing, authorizing, certifying, and recertifying CMMC assessors, instructors, and related individuals. § 170.12(b) in the rule was updated to add the requirement for a CCI to be certified at or above the level of training they are delivering. The DoD also modified § 170.12(a)(11) to add CMMC Certified Professional (CCP) candidates. The DoD declined to remove the certification requirement for CCIs. Although CMMC Certified Assessors have the technical background, that does not imply that they meet all the instructor-unique qualifications necessary to be a CCI. The DoD modified § 170.12 to include requirements for Provisional Instructors prior to their transition to a CMMC Certified Instructor. Any Provisional Instructor (PI) will be required to achieve certification under the CMMC Certified Instructor (CCI) program within 18 months of the final rule publication. The PI designation ends 18 months after the effective date of the rule. f. Conflicts of Interest and Code of Professional Conduct Comment:

Additional information about this publication is available at <https://csrc.nist.gov/pubs/ir/8523/final>, including related content, potential updates, and document history. State agencies that have already implemented MFA may decide to offer an MFA service to local agencies within their jurisdiction, as shown in Fig. 9. This model might be offered only to small or rural agencies who may lack the necessary funding and/or knowledge to implement MFA on their own, or the state might consider a shared service model where identity services are offered to all eligible and interested agencies within the state. Such an approach could result in economies of scale that could save costs for both state and local agencies and could also reduce the number of MFA architectures and implementations needed across the state. Establishing a state-shared service might also afford agencies greater ability to influence vendor capabilities and updates, including updates to support standards and best practices for MFA. - [1] U.S. Department of Justice (2024) Criminal Justice Information Services (CJIS) Security Policy, Version 6.0. CJISSECPOL v6.0. Available at https://le.fbi.gov/filerepository/cjis/_security/_policy/_v6-0/_20241227.pdf - [2] Wisconsin Law Enforcement Network (2024) Public Safety Threat Report: 2024 Threat Landscape. https://wilenet.widj.gov/sites/default/files/public/_files-2025-02/ijis2024-threat-landscape-report.pdf - [3] Temoshok D, Proud-Madruga D, Choong YY, Galluzzo R, Gupta S, LaSalle C, Lefkovitz N, Regenscheid A (2025) Digital Identity Guidelines. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-63-4. <https://doi.org/10.6028/NIST.SP.800-63-4> - [4] Temoshok D, Fenton JL, Choong YY, Lefkovitz N,

Upon submission, the Government must review approximately 28 continuous monitoring strategies provided by contractors each year (see 39.X03(f)). It is estimated that a GS 15/step 5 employee will spend 20 hours reviewing, analyzing, and processing a contractor's submission. Using an average loaded wage rate of \$113.46 for GS 15/step 5 employees, the total annual estimated cost for the Government to review, analyze, and file 28 continuous monitoring strategy submissions each year is approximately \$63,538 (28 responses * 20 hours * \$113.46). V. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This rule is a significant regulatory action under E.O. 12866, and therefore, was subject to review under Section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. VI. Regulatory Flexibility Act DoD, GSA, and NASA do not expect this proposed rule, when finalized, to have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601-612, because the rule applies to a small number of entities that develop, implement, operate, or maintain a FIS on behalf of the Government. However, an Initial Regulatory Flexibility Analysis (IRFA) has been performed and is summarized as follows: DoD, GSA, and NASA are proposing to amend the Federal Acquisition Regulation (FAR) to implement standardized cybersecurity contractual requirements across Federal agencies for unclassified Federal Information Systems (FIS) pursuant to recommendations received in accordance with paragraph (i) of section 2 of E.O. 14028, 'Improving the Nation's Cybersecurity,' dated May 12, 2021. The objective of this rule is to implement standardized cybersecurity requirements in Federal contracts for services to develop, implement, operate, or maintain a FIS on behalf of the Government. This rule will help protect and secure FISs, while streamlining the cybersecurity requirements for applicable contracts and improving contractor and Federal compliance with cybersecurity requirements for these systems. The legal basis for this rule is paragraph (i) of section 2 of Executive Order 14028, 'Improving the Nation's Cybersecurity,' dated May 12, 2021; and paragraphs (a) and (b)(1) of section 7 of the Internet of Things (IoT) Cybersecurity Improvement Act of 2020 (Pub. L. 116-207). Promulgation of FAR regulations is authorized by 40 U.S.C. 121(c) ; 10 U.S.C. chapter 4 and 10 U.S.C. chapter 137 legacy provisions (see 10 U.S.C. 3016); and 51 U.S.C. 20113 .

From the NIST SP 800-172 Rev 3 Final Public Draft: The defender then analyzes (malware and forensic analysis) the malware captured in the honeynet to determine the nature of the attacker's TTPs, allowing it to develop appropriate defenses. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 INTENDED EFFECT IMPACT ON RISK EXPECTED RESULTS Reveal Increase the awareness of risk factors and the relative effectiveness of remediation approaches across the stakeholder community to support common, joint, or coordinated risk response. Reduce the likelihood of impact, particularly in the future. · The adversary loses the advantage of surprise and possible deniability. · The adversary's ability to compromise one organization's systems to attack another organization is impair

) The CSA, GCA, or controlling agency becomes aware of adverse information that impacts the entity eligibility determination. (ii) The CSA's threat assessment pertaining to the entity indicates a risk to one of the categories of proscribed information. (iii) The CSA becomes aware of any material change regarding the source, nature, and extent of FOCI. (iv) The entity's record of NISP compliance, based on CSA reviews, becomes less than satisfactory. Consult DOE Order 470.4B for additional information and requirements for processing NID requests for access to RD. (5) Under any of the circumstances in paragraphs (d)(2)(iii)(B)(4)(i) through (d)(2)(iii)(B)(4)(iv) in this section, the CSA determines whether the entity remains eligible for access to classified information, it must change the FOCI mitigation measure in order to remain eligible for access to classified information, or the CSA must terminate or revoke the access to classified information. (6) When an entity is eligible for access to classified information that includes a favorable NID for SCI, RD, or COMSEC, the CSA does not have to request a new NID concurrence for the same entity if the access to classified information requirements for the relevant category of proscribed information and terms remain unchanged for: (i) Renewing the contract or agreement. (ii) New task orders issued under the contract or agreement. (iii) A new contract or

agreement that contains the same provisions as the previous one (this usually applies when the contract or agreement is for a program or project.) (iv) Renewing the SSA. (7) Under certain conditions, entities under an SSA may not require a NID for one or more categories of proscribed information in accordance with CSA-provided guidance. Categories of proscribed information for entities under SSAs not requiring a NID will be recorded in the CSA's system of record for entity eligibility determinations. (iv) Voting Trust (VT) or Proxy Agreement (PA). The VT and the PA are arrangements that vest the voting rights of the foreign-owned stock in cleared U.S. citizens approved by the USG. Under a VT, the foreign owner transfers legal title its ownership interests in the entity to the trustees. Under a PA, the foreign owner's voting rights are (printed page 83333) conveyed to the proxy holders. Neither arrangement imposes any restrictions on the entity's eligibility to have access to classified information or to compete for classified contracts. (A) Establishment of a VT or PA involves the selection of trustees or proxy holders, all of whom must become members of the entity's governing board. Both arrangements must provide for the exercise of all prerogatives of ownership by the trustees or proxy holders with complete freedom to act independently from the foreign owners, except as provided in the VT or PA. The arrangements may limit the authority of the trustees or proxy holders by requiring approval be obtained from the foreign owner with respect to issues such as: (1

State and local officials who assist with FD&C Act examinations and inspections are issued one or two types of credentials that differ in scope. All commissioned individuals receive Certificates of Commission and are permitted to receive and review FDA documents. A subset of commissioned individuals also receive personal ·pocket credentials· identifying them as FDA commissioned officers and authorizing them to perform additional activities such as conducting inspections, collecting samples, and verifying records. To obtain pocket credentials, State and local officials undergo an Office of Personnel Management level 5 background investigation. FDA commission credentials are different from the PIV badges issued to FDA employees and contractors, and are manufactured and issued by FDA's Office of Security Operations, and are not within the scope of HHS department-wide SORN No. 09-90-0777. II. The Privacy Act The Privacy Act of 1974 (Pub. L. 93-579) (5 U.S.C. 552a), as amended, governs the means by which the U.S. Government collects, maintains, and uses information about individuals in a system of records. A ·system of records· is a group of any records under the control of a Federal Agency from which information about an individual is retrieved by the individual's name or other personal identifier. The Privacy Act requires each Agency to publish in the Federal Register a SORN identifying and describing each system of records the Agency maintains, including the purposes for which the Agency uses information about individuals in the system, the routine uses for which the Agency discloses such information outside the Agency, and how individual record subjects can exercise their rights under the Privacy Act (for example, to determine if the system contains information about them). (printed page 72688) A. System Number 09-10-0022 B. System Name FDA Commissioning of State and Local Officials, HHS/FDA/OR. C. Security Classification Unclassified. D. System Location Records are maintained at several FDA Headquarters locations and in component offices of the FDA, in both Montgomery County, MD and field locations across the United States. E. Categories of Individuals Covered by the System The records in this system will contain data collected from the FDA commissioning applications of individuals who are State and local officials who wish to be commissioned under section 702(a)(1)(A) of the FD&C Act. This information is gathered for the purpose of processing and validating each individual's qualifications for commissioning, to initiate the mandatory background investigation, and to track the status of commissioned officials.

Incident Response Recommendations and Considerations for Cybersecurity Risk Management ##
 Incident Response Recommendations and Considerations for Cybersecurity Risk Management Nelson A, Rekhi S, Souppaya M, Scarfone K (2025) Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-61r3.
<https://doi.org/10.6028/NIST.SP.800-61r3>

CIS Safeguard 6.3 · Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.
 Implementation Groups: 1,2,3 Asset Type: users Security Function: protect Parent Control: Access Control Management

179. Guidance Document: Information for Healthcare Organizations about FDA's 'Guidance for Industry: Cybersecurity for Networked Medical Devices Containing Off-The-Shelf (OTS) Software,' U.S. Food & Drug Administration, U.S. Department of Health and Human Services (Feb. 2005), <https://www.fda.gov/regulatory-information/search-fda-guidance-documents/information-healthcare-organizations-about-fdas-guidance-industry-cybersecurity-networked-medical> . Back to Citation

180. Elizabeth Gourd, 'Increase in health-care cyberattacks affecting patients with cancer,' *The Lancet*, p. 1215 (Sept. 2021), [https://doi.org/10.1016/S1470-2045\(21\)00451-4](https://doi.org/10.1016/S1470-2045(21)00451-4) . Back to Citation

181. See Mayo Clinic, <https://www.mayoclinic.org/> . Back to Citation

182. An 'ethical hacker' is a cybersecurity researcher who 'use[s] penetration testing techniques to test an organization's cybersecurity and information technology (IT) security.' See Ed Tittel, 'How to Become a White Hat Hacker,' *Business News Daily* (June 17, 2024), <https://www.businessnewsdaily.com/10713-white-hat-hacker-career.html> . Back to Citation

183. See Foued Badrouchi, et al., 'Cybersecurity Vulnerabilities in Biomedical Devices: A Hierarchical Layered Framework,' *Internet of Things Use Cases for the Healthcare Industry*, p. 157-58 (2020); see also Monte Reel, et al., 'It's Way Too Easy to Hack the Hospital,' *Bloomberg Businessweek* (Nov. 2015), <https://www.bloomberg.com/features/2015-hospital-hack/> . Back to Citation

184. See 'Cybersecurity Vulnerabilities in Biomedical Devices: A Hierarchical Layered Framework,' *supra* note 183, p. 157-58. Back to Citation

185. See also 'It's Way Too Easy to Hack the Hospital,' *supra* note 183; Nicole M. Thomasian, et al., 'Cybersecurity in the internet of Medical Things,' *Health Policy and Technology* (Sept. 2021), <https://doi.org/10.1016/j.hlpt.2021.100549> . Back to Citation

186. 'Cybersecurity in the internet of Medical Things,' *supra* note 185. Back to Citation

187. *Id.* Back to Citation

188. *Id.* Back to Citation

189. *Id.* Back to Citation

190. Report to Congressional Committees, 'Medical Device Cybersecurity: Agencies Need to Update Agreement to Ensure Effective Coordination,' U.S. Government Accountability Office, p. 1 (Dec. 2023), <https://www.gao.gov/assets/d24106683.pdf> . Back to Citation

191. 'Medical Device Interoperability,' U.S. Food & Drug Administration, U.S. Department of Health and Human Services, <https://www.fda.gov/medical-devices/digital-health-center-excellence/medical-device-interoperability> . Back to Citation

192. Guidance for Industry and Food & Drug Administration Staff, 'Cybersecurity in Medical Devices: Quality System Considerations and Content of Premarket Submissions,' U.S. Food & Drug Administration, U.S. Department of Health and Human Services (Sept. 27, 2023), <https://www.fda.gov/media/119933/download> . Back to Citation

193. 45 CFR 160.103 (definition of 'Health care provider'). Back to Citation

(2) The Office of the Secretary of Defense issued a policy memorandum in 2001 that provided greater protection of DOD personnel in the aftermath of 9/11 by requiring information that personally identifies DOD personnel be more carefully scrutinized and limited. In general, the Department of Defense has specifically advised that DOD components are not to release lists of names, duty addresses, present or past position titles, grades, salaries, and performance standards of DOD military members and civilian employees. At the office director level or above, the release of information will be limited to the name, official title, organization, and telephone number, provided a determination is made that disclosure does not raise security or privacy concerns. No other information, including room numbers, will normally be released about these officials. Consistent with current policy, information on officials below the office director level may continue to be released if their positions or duties require frequent interaction with the public.

(3) Disclosure of records pertaining to personnel of overseas, sensitive, or routinely deployed units shall be prohibited to the extent authorized by 10 U.S.C. 130b . (e) Release of home addresses and home telephone numbers. (1) The release of home addresses and home telephone numbers normally is prohibited. This release is normally considered a clearly 'unwarranted invasion' of personal privacy and is exempt from mandatory release under the FOIA. However, home addresses and home telephone numbers may still be released if: (i) The individual has indicated previously in writing that he or she has no objection to the release; (ii) The source of the information to be released is a public document such as commercial telephone directory or other public listing; (iii) The release is required by Federal statute (for example, pursuant to federally funded state programs to locate parents who have defaulted on child support payments) (See 42 U.S.C. 653); or (iv) The releasing of information is pursuant to the routine use exception or the 'intra-agency need to know' exception to the Privacy Act. (2) A request for a home address or telephone number may be referred to the last known address of the individual for a direct reply by the individual to the requester. In such cases, the requester shall be notified of the referral. (3) Do not sell or rent lists of individual names and addresses unless such action is specifically authorized by the appropriate

authority. (f) Emergency Recall Rosters. (1) The release of emergency recall rosters normally is prohibited. Their release is normally considered a clearly ·unwarranted invasion· of personal privacy and is exempt from mandatory release under the FOIA. Emergency recall rosters should only be shared with those who have an ·official need to know· the information, and they should be marked ·For Official Use Only· (See AR 25-55).

a FIS that uses non-cloud computing services and a FIS that uses cloud computing services). When an acquisition requires the use of both non-cloud computing services and cloud computing services in performance of the contract, the rule would require compliance with the policies, procedures, and requirements for each service approach, as they respectively apply to the FIS. This rule proposes to: (1) add a new FAR subpart 39.X, ·Federal Information Systems,· to prescribe policies and procedures for agencies when acquiring services to develop, implement, operate, or maintain a FIS; (2) add and revise definitions in parts 2 and 39.X using current language from statute, regulation, Office of Management and Budget memoranda and circulars, and National Institute of Standards and Technology (NIST) Special Publications (SP) guidance; (3) make conforming changes to parts 4, 7, 37, and 39 to further implement policies and procedures described below; and (4) add two new FAR clauses to be used in contracts for services to develop, implement, operate, or maintain a FIS: FAR clause 52.239-YY, ·Federal Information Systems Using Non-Cloud Computing Services,· which is included in solicitations and contracts that use non-cloud computing services in performance of the contract; and FAR clause 52.239-XX, ·Federal Information Systems Using Cloud Computing Services,· which is included in solicitations and contracts that use cloud computing services in performance of the contract. The policies and requirements specified in this rule are discussed below. A. FISs Using Non-Cloud Computing Services FIPS Publication 199 Impact Level and Mandatory Security and Privacy Controls. As each requirement will vary in scope, as well as the function of each FIS, adequate security and privacy controls must be identified when agencies define their acquisition requirements. Agencies will use Federal Information Processing Standard (FIPS) Publication 199 to categorize the FIS based on its impact analysis of the information processed, stored, or transmitted by the system. As a result of the analysis, the FIPS Publication 199 impact level of the FIS, as well as a set of necessary security and privacy controls for the FIS, will be specified by the agency in the contract. As part of the security and privacy controls identified by the agency, the rule would require agencies to address multifactor authentication, administrative accounts, consent banners, Internet of Things device controls, and assessment requirements, when applicable, in every applicable contract. The proposed rule adds text to FAR part 7 to ensure that acquisition planners develop agency requirements in accordance with the rule's requirements. Records Management and Government Access.

Tier 3 addresses risk from an information system perspective and is guided by the risk context, risk decisions and risk activities at Tiers 1 and 2. Tier 3 risk management activities include: (i) categorizing organizational information systems; (ii) allocating security controls to organizational information systems and the environments in which those systems operate consistent with the organization's established enterprise architecture and embedded information security architecture; and (iii) managing the selection, implementation, assessment, authorization, and ongoing monitoring of allocated security controls as part of a disciplined and structured system development life cycle process implemented across the organization. At Tier 3, information system owners, common control providers, system and security engineers, and information system security officers make risk-based decisions regarding the implementation, operation, and monitoring of organizational information systems. Based on these day-to-day operational riskbased decisions, authorizing officials make follow-on risk-based decisions on whether or not the information systems are initially authorized to operate within the designated environments of operation or continue to receive authorization to operate on an ongoing basis. These ongoing riskbased decisions are informed by the risk management process with guidance from the risk executive (function) and the various architectural considerations supporting the mission/business processes. In addition, the activities at Tier 3 provide essential feedback to Tiers 1 and 2. New vulnerabilities discovered in an organizational information system, for example, may have systemic implications that extend organization-wide. Those same vulnerabilities may trigger changes to the enterprise architecture and embedded information security architecture or may require an adjustment to the organizational risk tolerance.

. This proposed standard would require a regulated entity to deploy technical controls to create and maintain backups of relevant electronic information systems. It would also require a regulated entity to review and test the effectiveness of such technical controls at least once every six

months or in response to environmental or operational changes, whichever is more frequent, and modify them as reasonable and appropriate. The Department would not require a regulated entity to test every relevant electronic information system; rather, the requirement to test the effectiveness of the controls would permit a regulated entity to review the relevant log files and to test a representative sample of the backup of its relevant electronic information systems. This proposed standard would reduce potential gaps in the data that needs to be backed up and recovered, to ensure that regulated entities address compliance across relevant electronic information systems. It is crucial to a regulated entity's recovery from an emergency or other occurrence, including a security incident, that adversely affects its relevant electronic information systems to create and maintain backups of such information systems that comprise the infrastructure that maintains and supports the confidentiality, integrity, and availability of ePHI. The Department would expect that the extent of this activity would be affected by the size and complexity of the relevant electronic information systems used by a regulated entity. It is also consistent with NIST guidance, which directs regulated entities to consider whether backups or images of operating systems, devices, software, and configuration files necessary to support the (printed page 980) confidentiality, integrity, and availability of ePHI. [817]

4. Request for Comment The Department requests comments on the foregoing proposals, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular:

- a. Whether there are additional technical safeguards that the Department should require regulated entities to implement.
- b. Whether there are additional implementation specifications that should be adopted for any of the proposed or existing technical safeguards.
- c. Whether the Department should extend the standard for encryption and decryption and associated implementation specifications to require encryption of all relevant electronic information systems.

3.4.5 | Application Whitelisting ... 3.4.5 Application Whitelisting Application whitelisting technologies, also known as application control programs, are used to specify which applications are authorized for use on a host. 3.4.5) to prevent unauthorized applications from being run within it.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST Special Publication 800 NIST SP 800-172r3 fpd Enhanced Security Requirements for Protecting Controlled Unclassified Information Final Public Draft Ron Ross Victoria Pillitteri This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-172r3.fpd> NIST Special Publication 800 NIST SP 800-172r3 fpd Enhanced Security Requirements for Protecting Controlled Unclassified Information Final Public Draft Ron Ross Victoria Pillitteri Computer Security Division Information Technology Laboratory This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-172r3.fpd> September 2025 U.S. Department of Commerce Howard Lutnick, Secretary National Institute of Standards and Technology Craig Burkhardt, Acting Under Sec

Below is a summary of the significant program changes and adjustments proposed since the approved 2024 ICR; because the ICR addresses regulatory burdens associated with the full suite of HIPAA Rules, the changes and adjustments include updated data and estimates for some provisions of the HIPAA Rules that are not affected by this proposed rule. These program changes and adjustments form the bases for the burden estimates presented in the ICR associated with this NPRM. Adjusted Estimated Annual Burdens of Compliance

- (1) Updating the number of covered entities.
- (2) Updating hourly wage rates.
- (3) Adjusting downward the number of estimated requests for an exception to Federal preemption of State law to the prior baseline of 1 request per year.
- (4) Adjusting downward the estimated hourly burden for regulated entities to report security incidents (not breaches) from 20 hours per monthly report to 10 hours per monthly report.
- (5) Updating the number of research disclosures.

New Burdens Resulting From Program Changes In addition to the adjustments above, the Department proposes to add new annual estimated burdens as a result of program changes, as follows:

- (1) A burden of 2 hours for each regulated entity to conduct a Security Rule compliance audit.
- (2) A burden of 2 hours for each business associate (including each subcontractor) to provide verification of compliance with technical safeguards.
- (3) A burden of .5 hours for each covered entity to obtain verification of business associates' compliance with technical safeguards.
- (4) A burden of .083 hours for each business associate to obtain verification of subcontractors' compliance with technical safeguards.
- (5) A burden of 1 hour for each regulated entity to provide notification to other regulated entities of workforce members' termination of access to ePHI.
- (6) A burden of 1.5 hours for each regulated entity to deploy MFA.
- (7) A burden of 4.5 hours for each regulated entity to perform network segmentation.
- (8) A burden of .5 hours for approximately 76.56 percent of regulated entities to disable unused ports and remove extraneous software.
- (9) A burden

of 3 hours for each regulated entity to conduct penetration testing. (10) A burden of .5 hours for each regulated entity to notify covered entities or business associates, as applicable, upon activation of a contingency plan. (11) A burden of .5 hours for each insurer and third-party administrator to update health plan documents. (12) A burden of 2 hours for each regulated entity to update the content of its cybersecurity awareness and Security Rule training program. (13) A burden of 3.5 hours for each regulated entity to update its policies and procedures. (14) A burden of 1 hour for each regulated entity to update business associate agreements. (15) A burden of 52.92 hours for each health plan sponsor to modify safeguards for its relevant electronic information systems to meet Security Rule standards. List of Subjects 45 CFR Part 160 Administrative practice and procedure

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.02.03E Literacy and Awareness Training Feedback 801 Provide feedback on organizational training results to the following personnel [Assignment: organization-defined personnel]. DISCUSSION Training feedback includes literacy and role-based training results, which can indicate a potentially serious problem, especially the failures of personnel in critical roles. Managers should be made aware of such situations so that they can respond accordingly. Training feedback supports the evaluation and update of organizational training content and methodology. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Preclu

(8) Nothing contained in this section affects the authority of a Federal agency head to limit, deny, or revoke access to classified information under its statutory, regulatory, or contract jurisdiction. (b) Factors. Factors relating to the entity, relevant foreign interests, and the government of such foreign interests, as appropriate, will be considered in the aggregate to determine whether an applicant entity is under FOCI, its eligibility for access to classified information, and the protective measures required. These factors include: (1) Record of espionage against U.S. targets, either economic or government. (2) Record of enforcement actions against the entity for transferring technology without authorization. (3) Record of compliance with pertinent U.S. laws, regulations, and contracts or agreements. (4) Type and sensitivity of the information the entity would access. (5) Source, nature, and extent of FOCI, including whether foreign interests hold a majority or minority position in the entity, taking into consideration the immediate, intermediate, and ultimate parent entities. (6) Nature of any relevant bilateral and multilateral security and information exchange agreements. (7) Ownership or control, directly or indirectly, in whole or in part, by a foreign government. (8) Any other factor that indicates or demonstrates capability of foreign interests to control or influence the entity's operations or management. (c) Procedures. An entity is required to complete an SF 328 during the process for an entity eligibility determination or when significant changes occur to information previously submitted. In the case of a corporate family, the form may be a consolidated response rather than separate submissions from individual members of the corporate family based on CSA guidance. (1) If an entity provides any affirmative answers on the SF 328, or the CSA receives other information which indicates that the applicant entity may be under FOCI, the CSA will make a risk-based determination regarding the relative significance of the information in regard to: (i) Whether the applicant is under FOCI. (ii) The extent and manner to which the FOCI represents a risk to the national security or may adversely impact classified contract performance. (iii) The type of actions, if any, that would be necessary to mitigate or negate the effects of FOCI to a level deemed acceptable to the USG. The CSA will advise entities on the CSA's appeal channels for disputing CSA FOCI determinations. (2) When an entity with a favorable eligibility determination enters into negotiations for the proposed merger, acquisition, or takeover by a foreign interest, the entity will submit notification to the CSA of the commencement of such negotiations. (i) The submission will include the type of transaction under negotiation (e.g.,

cybersecurity attacks impacting the Nation's economy? In addition, the U.S. Government, as a potential user of electric vehicles and EVSE, is concerned about how cybersecurity threats to the charging infrastructure might affect government activities. These concerns, as well as policy interests in the adoption of electric vehicles, have led to research efforts sponsored by federal agencies to examine potential cybersecurity issues. Because EVSE is a relatively new infrastructure, multiple researchers pointed out the lack of understanding of the risks and necessary controls. As a result, multiple researchers devoted significant attention to the development of threat models. Reliable threat models are needed to help determine what risks exist

and what controls might mitigate such risks. Without threat models, it is difficult for manufacturers, users, and the Government to make risk-based decisions on the controls needed. - Threat Model of Vehicle Charging Infrastructure (Sandia National Labs) - Enabling Secure and Resilient XFC: A Software/Hardware-Security Co-Design Approach (Virginia Tech) - Consequence-Driven Cybersecurity for High-Power Charging Infrastructure (Idaho National Labs) - Cybersecurity for Grid Connected eXtreme Fast Charging (XFC) Station (CyberX) (ABB)

(8) Address all appeals arising from the CMMC assessor, instructor, and practitioner authorizations and certifications process through use of internal processes in accordance with ISO/IEC 17024:2012, or subsequent revisions. (9) Maintain records for a period of six (6) years of all procedures, processes, and actions related to fulfillment of the requirements set forth in this section and provide the Accreditation Body access to those records. (10) Provide the Accreditation Body information about the authorization and accreditation status of assessors, instructors, training community, and publishing partners. (11) Ensure separation of duties between individuals involved in testing activities, training activities, and certification activities. (12) Safeguard and require any subcontractor, as applicable, to safeguard the confidentiality of applicant, candidate, and certificate-holder information and ensure the overall security of the certification process. (13) Ensure that all personal information is encrypted and protected in all CAICO and CAICO subcontractor, as applicable, information systems and databases. (14) Ensure the security of assessor and instructor examinations and the fair and credible administration of examinations. (15) Neither disclose nor allow any subcontractor, as applicable, to disclose CMMC data or metrics related to authorization or certification activities to any entity other than the Accreditation Body and DoD, except as required by law. (16) Require retraining and recertification of CCAs, CCIs, and CCPs upon significant change to DoD's CMMC Program requirements under this rule. § 170.11 CMMC Certified Assessor (CCA). (a) Roles and responsibilities. CCAs, in support of a C3PAO, conduct CMMC Level 2 Certification Assessments of OSCs in accordance with NIST SP 800-171A (incorporated by reference, see § 170.2), the assessment processes defined in § 170.17, and the scoping requirements defined in § 170.19. CCAs are certified by the CAICO after successful completion of the CCA training and testing requirements set forth in paragraph (b) of this section. A CCA may conduct CMMC Level 2 Certification Assessments and participate on a C3PAO Assessment Team. (b) Requirements. CCAs shall: (1) Obtain and maintain certification from the CAICO in accordance with the requirements set forth in § 170.10. Certification is valid for 3 years from the date of issuance. (2) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17). (3) Complete a Tier 3 background investigation resulting in a determination of national security eligibility. This Tier 3 background investigation will not result in a security clearance and is not being executed for the purpose of government employment. The Tier 3 background investigation is initiated using the Standard Form (SF) 86. These positions are designated as non-critical sensitive with a risk designation of 'Moderate Risk' in (printed page 89127)

3.1.2 | Base Metrics... 3.1.2 Perceived Target Value (PTV) The Perceived Target Value metric measures the likelihood of attack using the configuration issue in an environment relative to vulnerable systems in other environments. 3.1.2 Base Metrics ## 3.

employing the technology? Often we are not seeing that information.' An essential element of manufacturer communications is clear explanation of customer responsibilities for IoT device cybersecurity. Consumers, for example, primarily need basic installation and configuration guidance, whereas organizational customers need more extensive documentation to address device configurability, deployment of devices at scale, and information enabling the organization to ensure it is able to satisfy its legal obligations. All customers need clarity regarding available manufacturer communications channels, frequency of software updates, and end-of-life dates beyond which specific IoT devices will no longer be supported.

3.2.7 | Tampering of Storage-Related Log and Audit Data... 3.2.7 Tampering of Storage-Related Log and Audit Data The tampering of storage-related log and audit data is where an attacker deletes or modifies log data to prevent an effective audit trail in an effort to conceal the attack (in real-time or afterwards) or to mislead the people investigating attacks with false information.

CIS Safeguard 3.12 · Segment Data Processing and Storage Based on Sensitivity Segment data processing and storage, based on the sensitivity of the data. Do not process sensitive data on

enterprise assets intended for lower sensitivity data. Implementation Groups: 2,3 Asset Type: network Security Function: protect Parent Control: Data Protection

§ 164.414 Administrative requirements and burden of proof. (a) Administrative requirements. A covered entity is required to comply with the administrative requirements of § 164.530(b) , (d) , (e) , (g) , (h) , (i) , and (j) with respect to the requirements of this subpart. (b) Burden of proof. In the event of a use or disclosure in violation of subpart E, the covered entity or business associate, as applicable, shall have the burden of demonstrating that all notifications were made as required by this subpart or that the use or disclosure did not constitute a breach, as defined at § 164.402 .

means any agreement between one or more Federal laboratories and one or more non-Federal parties under which the Government, through its laboratories, provides personnel, services, facilities, equipment, intellectual property, or other resources with or without reimbursement (but not funds to non-Federal parties) and the non-Federal parties provide funds, personnel, services, facilities, equipment, intellectual property, or other resources toward the conduct of specified research or development efforts which are consistent with the missions of the laboratory; except that such term does not include a procurement contract or cooperative agreement as those terms are used in sections 6303, 6304, and 6305 of title 31. Corporate family means an entity, its parents, subsidiaries, divisions, and branch offices. Counterintelligence means information gathered and activities conducted to protect against espionage, other intelligence activities, sabotage, or assassinations conducted for or on behalf of foreign powers, organizations or persons, or international terrorist activities, but not including personnel, physical, document or communications security programs. Courier means a cleared employee, designated by the contractor, whose principal duty is to transmit classified material to its destination, ensuring that the classified material remains under their constant and continuous protection and that they make direct point-to-point delivery. CRYPTO means the marking or designator that identifies unencrypted COMSEC keying material used to secure or authenticate telecommunications carrying classified or sensitive USG or USG-derived information. This includes non-split keying material used to encrypt or decrypt COMSEC critical software and software based algorithms. CSA means an agency designated as having NISP implementation and security responsibilities for its own agencies (including component agencies) and any entities and non-CSA agencies under its cognizance. The CSAs are: DoD; DOE; NRC; ODNI; and DHS. CSO means an organizational unit to which the head of a CSA delegates authority to administer industrial security services on behalf of the CSA. CUI means information the USG creates or possesses, or that an entity creates or possesses for or on behalf of the USG, that a law, regulation, or USG-wide policy requires or permits an agency to handle using safeguarding or dissemination controls. However, CUI does not include classified information or information a non-executive branch entity possesses and maintains in its own systems that did not come from, or was not created or possessed by or for, an executive branch agency or an entity acting for an agency. Custodian means an individual who has possession of, or is otherwise charged with, the responsibility for safeguarding classified information. Cybersecurity

Participation in the DIB CS Program is voluntary. Program application and participation costs are described in the cost analysis section of this proposed rule. These costs are voluntarily incurred and associated with the labor and resource costs to complete the required program paperwork, including execution of the Framework Agreement, to submit information to the Government, and to receive information from the Government. The costs associated with applying to the DIB CS Program are associated exclusively with labor costs and estimated to be \$18.15 per company. None of the program's offering come at an additional fee to DIB participants and additional costs related to participation are estimated based on the time investment (labor hours) required to obtain the benefits as described in the cost analysis of this preamble. Therefore, the Regulatory Flexibility Act, as amended, does not require us to prepare a regulatory flexibility analysis. D. Sec. 202, Public Law 104-4 , ·Unfunded Mandates Reform Act· Section 202 of the Unfunded Mandates Reform Act of 1995 (2 U.S.C. 1532) requires agencies to assess anticipated costs and benefits before issuing any rule whose mandates require spending in any one year of \$100 million in 1995 dollars, updated annually for inflation. When the Federal Government passes legislation requiring a State, local, or tribal government to perform certain actions or offer certain programs but does not include any funds for the actions or programs in the law, an unfunded mandate results. This proposed rule will not mandate any requirements for State, local, or tribal governments, and will not mandate private sector incurred costs above the \$100 million threshold defined in 2 U.S.C. 1532 . E.

Public Law 96-511, "Paperwork Reduction Act" (44 U.S.C. Chapter 35) This proposed rule contains the following information collection requirements under the Paperwork Reduction Act (PRA) of 1995. 0704-0489, "DoD's Defense Industrial Base (DIB) Cybersecurity (CS) Activities Cyber Incident Reporting," 0704-0490, "DoD's Defense Industrial Base (DIB) Cybersecurity (CS) Points of Contact (POC) Information." With the revisions in eligibility criteria, DoD expects the burden associated with both collections to increase as additional defense contractors join the DIB CS Program and additional cyber threat information is reported. DOD is requesting comments on both collections as part of this proposed rule. Additional information regarding these collections of information including all background materials can be found at <https://www.reginfo.gov/public/do/PRAMain> by using the search function to enter either the title of the collection or the Office of Management and Budget (OMB) Control Number. Comments are invited on:

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 vii List of Tables 147 Table
1. Enhanced security requirement families
.....6 Table 2. Enhanced
security requirements.....
..... 93 Table 3. Effects of cyber resiliency techniques on adversarial threat events
..... 99 Table 4. Organization-defined parameters
..... 104 Table 5.
Change Log Error!
Bookmark not defined. List of Figu

Access Control: Access to IT and OT systems is based on the principle of least privilege depending on the user's role in the organization. Proper authorization and approval by the Director of Operations are required prior to granting access or operating any components of the manufacturing system. Controls are in place to restrict access through authentication methods and other technical means. Passwords are managed through a formal process and secure log-on procedures. Sensitive systems are explicitly identified and audited regularly. 1. Employees must complete cybersecurity awareness training and agree to uphold the acceptable use policy. 2. Employees must immediately notify the Director of Operations if an unescorted or unauthorized individual is found in the facility. 3. Employees must always use a secure password on all systems as per the password policy. These credentials must be unique and must not be used on other external systems or services. 4. Terminated employees must return all company records, in any format. 5. Employees must verify with the Director of Operations that authorizations have been granted before allowing external personnel to connect to the IT or OT network. 6. Employees must report any physical or cybersecurity incidents to the Director of Operations.

The Department proposes to add a definition of "electronic information system" to better distinguish the concept from the broader category of an information system. Accordingly, the Department would limit the definition to an interconnected set of electronic information resources under the same direct management control that shares common functionality. Under this proposal, an electronic information system generally would include technology assets, such as hardware, software, electronic media, data, and information. 8. Modifying the Definition of "Information System" a. Current Provision and Issues To Address As discussed above, the Department seeks to clarify the scope of an information system, as compared to an electronic information system. We believe that it would be beneficial to align the common elements of these terms and clarify the relationship between them, given their importance to compliance with requirements of the Security Rule. Additionally, the changes in the environment, such as the shift to cloud-based computing, may raise questions regarding the Department's interpretation of "direct management control." b. Proposal Accordingly, the Department proposes to modify the definition of "information system," to clarify that an information system "generally," not just "normally," includes hardware, software, data, communications, and people. The Department believes this proposed modification, combined with the existing broad reference to "resources," more accurately reflects the typical components of an information system and the full extent of resources that are addressed by the Security Rule. We also propose to remove "applications" from the list of technology assets that are generally included in an information system because applications are a type of software, making the inclusion of applications redundant. This proposed modification would not alter our interpretation that an information system includes applications. We use this opportunity to affirm that a technology asset

may be included as part of the information systems of multiple regulated entities where such regulated entities all have direct management control over the technology asset. For example, both a health care provider and a cloud-based EHR vendor have direct management control over the ePHI in the cloud-based EHR. Accordingly, such ePHI generally is part of both the information system of the health care provider and of the cloud-based EHR vendor. Additionally, the EHR that is used to create, receive, maintain, or transmit ePHI, regardless of whether it is accessed using software installed on the health care provider's workstation(s) or an internet browser, generally is also part of the information system of both entities because both the health care provider and the vendor have direct management control over the EHR.

9. Modifying the Definition of ·Malicious software·

a. Current Provision and Issues To Address

(Response) FDA continues to believe that facilities that provide food to interstate conveyances should not be covered by the restaurant exclusion because they do not provide food directly to the consumer for immediate consumption. In fact, the food is prepared and provided to several possible intermediaries before reaching the consumer, such as the packer, transporter, and/or distributor, before reaching the interstate conveyance (e.g., airplanes, passenger trains, and cruise ships) that actually provides the food directly to the consumer for immediate consumption. FDA believes the risk is substantially higher when the food is not prepared and served directly to consumers for immediate consumption, but rather goes through a number of intermediaries before it reaches the consumer. In a traceback investigation, it is critical for FDA to be able to identify each entity that handled the suspect food. FDA would lose this ability if interstate conveyance caterers were exempted. In addition, this requirement is consistent with the registration interim final rule, which requires interstate conveyance caterers to register as manufacturers/processors. (Comment 77) Several comments urge FDA to reconsider the proposed regulations for airline caterers. The comments state that these proposed requirements are onerous, unnecessary, and are being unfairly applied to that industry and would bury the industry in volumes of information. The comments note that the same rationale FDA used for partially exempting retail facilities should apply to airline caterers as well. The comments further state that the airline catering industry currently must be in compliance with many Government regulatory agencies (FDA, Federal Aviation Administration (FAA), USDA, Environmental Protection Agency, Transportation Security Administration (TSA)), and that they have strict specifications for products and vendors, whereas most food service (printed page 71592) operations do not. The comments also note that they currently employ security companies to monitor their staff, the food processes in which they prepare meals, the equipment the food items are loaded into, and the process of how it gets on board the aircraft. They also state that their customers have always expected traceability of all products used on their flights as part of their food safety and hygiene audits to resolve flight passenger complaints, food poisoning reports, and for other purposes, but not to the extent that is required by the proposed rule.

CMMC Program Requirements make no change to existing policies for information security requirements implemented by DoD. Policies for CUI and creation of program documentation, to include Security Classification Guides and FedRAMP equivalency are separate from this rule. Relevant policies include DoDI 5200.48 ·Controlled Unclassified Information· and DoD Manual 5200.45 ·Instructions for Developing Security Classification Guides· for example. [23] Some comments received lacked relevance to the rule's content, which is limited to specific CMMC program requirements. Changes to FAR and DFARS requirements are beyond the scope of this rule, as are the contents and updating of DoD's FAQ and Procurement Toolbox web pages. CMMC program requirements do not result in any change to which DoD organization makes the contract award. Recommendations to adopt standard DoD contracting procedures (i.e., to exclude CUI information in the basic award) are not within the scope of this rule, which outlines program requirements. The DoD limits the (printed page 83108) burden of CMMC compliance by requiring annual affirmations rather than annual assessments. Affirmations required for the CMMC program indicate that a DoD contractor has achieved and intends to maintain compliance with the applicable DoD information security requirements. The CMMC program is designed only to validate implementation of the information security standards in FAR clause 52.204-21, NIST SP 800-171 R2, and a selected subset of NIST SP 800-172 Feb2021. This rule does not address the other DFARS clause 252.204-7012 requirements for cyber incident reporting. The CMMC assessment framework will not alter, alleviate, or replace the cyber incident reporting aspects of DFARS clause 252.204-7012, which will remain effective where applicable. Classified information is managed differently from CUI, and different safeguarding regulations apply to these different categories of information (each of which are defined in 32 CFR part 2002). CMMC Program requirements are aligned to the requirements for safeguarding of CUI and are unrelated to the

requirements for safeguarding classified information. ·Export Controlled· is a category of CUI. To the extent that a company generates information it considers proprietary, but which is explicitly excluded from the definition of CUI (see 32 CFR part 2002), no CMMC requirements would apply. As the CMMC program requirements make no change to existing policies for information security requirements implemented by DoD, dialogues with industry to identify CUI is outside the scope of this 32 CFR part 170 CMMC Program rule. Several existing requirements directly address the human factors of cybersecurity, particularly those in the Awareness and Training, Personnel Security, and Physical Protection domains. Additional training and education on the topics of CUI safeguarding requirements, cybersecurity hygiene, and other useful topics may be found at: www.archives.gov/cui/training.html

Verification and Test Methods for Access Control Policies/Models ## Verification and Test Methods for Access Control Policies/Models Access control systems are among the most critical of computer security components. Faulty policies, misconfigurations, or flaws in software implementations can result in serious vulnerabilities. To formally and precisely capture the security properties that access control should adhere to, access control models are usually written, bridging the gap in abstraction between policies and mechanisms. Identifying discrepancies between policy specifications and their intended function is crucial because correct implementation and enforcement of policies by applications is based on the premise that the policy specifications are correct. As a result, policy specifications represented by models must undergo rigorous verification and validation through systematic verification and testing to ensure that the policy specifications truly encapsulate the desires of the policy authors. Verifying the conformance of access control policies and models is a non-trivial and critical task, and one important aspect of such verification is to formally check the inconsistency and incompleteness of the model and safety requirements of the policy, because an access control model and its implementation do not necessarily explicitly express the policy, which can also be implicitly embedded by mixing with direct access constraints or other access control models.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204, 232, and 252 [Docket DARS-2019-0019] RIN 0750-AK37 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Proposed rule. SUMMARY: DoD is proposing to amend the Defense Federal Acquisition Regulation Supplement (DFARS) to implement a section of the National Defense Authorization Act for Fiscal Year 2017, which amends 10 U.S.C. 2307 to address the use of performance-based payments. DATES: Comment Date: Comments on the proposed rule should be submitted in writing to the address shown below on or before July 1, 2019, to be considered in the formation of a final rule. ADDRESSES: Submission of Comments: Submit comments identified by DFARS Case 2019-D002, using any of the following methods: · Federal eRulemaking Portal: <http://www.regulations.gov> . Search for ·DFARS Case 2019-D002· Select ·Comment Now· and follow the instructions provided to submit a comment. Please include ·DFARS Case 2019-D002· on any attached documents. · Email: osd.dfars@mail.mil . Include DFARS Case 2019-D002 in the subject line of the message. · Fax: 571-372-6094. · Mail: Defense Acquisition Regulations System, Attn: Ms. Amy G. Williams, OUSD(A&S)DPC/DARS, Room 3B941, 3060 Defense Pentagon, Washington, DC 20301-3060. Comments received generally will be posted without change to <http://www.regulations.gov> , including any personal information provided. To confirm receipt of your comment(s), please check www.regulations.gov , approximately two to three days after submission to verify posting (except allow 30 days for posting of comments submitted by mail). FOR FURTHER INFORMATION CONTACT: Ms. Amy Williams, DPC/DARS, at 571-372-6106. SUPPLEMENTARY INFORMATION: I. Background DoD is proposing to amend DFARS subpart 232.10, Performance-Based Payments; amend the clauses at DFARS 252.232-7012, Performance-Based Payments-Whole Contract Basis, and DFARS 252.232-7013, Performance-Based Payments-Deliverable Item Basis; and add a new provision at 252.232-70XX, Performance-Based Payments-Representation, to implement section 831 the National Defense Authorization Act (NDAA) for Fiscal Year (FY) 2017, which amends 10 U.S.C. 2307 to address the use of performance-based payments. A proposed rule was published in the Federal Register on August 23, 2018 (83 FR 42831

updates on the review being conducted of the National Information Assurance Partnership, results of

the first Privacy Trust Survey of the U.S. government, customer relations management in the U.S. Postal Service (USPS), specifications and implementations of the Trusted Computing Group's Secure Platform and security issues with voice over IP (VoIP).

§ 170.9 CMMC Third-Party Assessment Organizations (C3PAOs). (a) Roles and responsibilities. C3PAOs are organizations that are responsible for conducting Level 2 certification assessments and issuing Certificates of CMMC Status to OSCs based on the results. C3PAOs must be accredited or authorized by the Accreditation Body in accordance with the requirements set forth. (b) Requirements. C3PAOs shall: (1) Obtain authorization or accreditation from the Accreditation Body in accordance with § 170.8(b)(3)(i) and (ii) . (2) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17) ; and achieve and maintain compliance with ISO/IEC 17020:2012(E) (incorporated by reference, see § 170.2) within 27 months of authorization. (3) Require all C3PAO company personnel participating in the Level 2 certification assessment process to complete a Tier 3 background investigation resulting in a determination of national security eligibility. This includes the CMMC Assessment Team and the quality assurance individual. This Tier 3 background investigation will not result in a security clearance and is not being executed for the purpose of government employment. The Tier 3 background investigation is initiated using the Standard Form (SF) 86 (www.gsa.gov/reference/forms/questionnaire-for-national-security-positions). These positions are designated as non-critical sensitive with a risk designation of 'Moderate Risk' in accordance with 5 CFR 1400.201(b) and (d) and the investigative requirements of 5 CFR 731.106(c)(2) . (4) Require all C3PAO company personnel participating in the Level 2 certification assessment process who are not eligible to obtain a Tier 3 background investigation to meet the equivalent of a favorably adjudicated Tier 3 background investigation. DoD will determine the Tier 3 background investigation equivalence for use with the CMMC Program only. (5) Comply with Foreign Ownership, Control or Influence (FOCI) by: (i) Completing and submitting Standard Form (SF) 328 (www.gsa.gov/reference/forms/certificate-pertaining-to-foreign-interests), Certificate Pertaining to Foreign Interests, upon request from DCSA and undergo a National Security Review with regards to the protection of controlled unclassified information based on the factors identified in 32 CFR 117.11(b) using the procedures outlined in 32 CFR 117.11(c) . (ii) Receiving a non-disqualifying eligibility determination from the CMMC PMO resulting from the FOCI risk assessment in order to proceed to a DCMA DIBCAC CMMC Level 2 assessment, as part of the authorization and accreditation process set forth in paragraph (b)(6) of this section. (iii) Reporting any change to the information provided on its SF 328 by resubmitting the SF 328 to DCSA within 15 business days of the change being effective. A disqualifying eligibility determination, based on the results of the change, will result in the C3PAO losing its authorization or accreditation. (6) Undergo a Level 2 certification assessment meeting all requirements for a Final Level 2 (C3PAO) in accordance with the procedures specified in § 170.17(a)(1) and (c) , with the following exceptions: (i) The assessment will be conducted by DCMA DIBCAC. (ii) The assessment will not result in a CMMC Status of Level 2 (C3PAO) nor receive a Certificate of CMMC Status. (7) Provide all documentation and records in English. (8) Submit pre-assessment and planning material, final assessment reports, and CMMC certificates of assessment into the CMMC instantiation of eMASS. (9) Unless disposition is otherwise authorized by the CMMC PMO, maintain all assessment related records for a period of six (6) years. Such records include any materials generated by the C3PAO in the course of an assessment, any working papers generated from Level 2 certification assessments; and materials relating to monitoring, education, training, technical knowledge, skills, experience, and authorization of all personnel involved in assessment activities; contractual agreements with OSCs; and organizations for whom consulting services were provided. (10) Provide any requested audit information, including any out-of-cycle from ISO/IEC 17020:2012(E) requirements, to the Accreditation Body. (11) Ensure that all personally identifiable information (PII) is encrypted and protected in all C3PAO information systems and databases. (12) Meet the requirements for Assessment Team composition. An Assessment Team must include at least two people: a Lead CCA, as defined in § 170.11(b)(10) , and at least one other CCA. Additional CCAs and CCPs may also participate on an Assessment Team. (13) Implement a quality assurance function that ensures the accuracy and completeness of assessment data prior to upload into the CMMC instantiation of eMASS. Any individual fulfilling the quality assurance function must be a CCA and cannot be a member of an Assessment Team for which they are performing a quality assurance role. A quality assurance individual shall manage the C3PAO's quality assurance reviews as defined in paragraph (b)(14) of this section and the appeals process as required by paragraphs (b)(19) and (20) of this section and in accordance with ISO/IEC 17020:2012(E) (incorporated by reference, see § 170.2) and ISO/IEC 17011:2017(E) (incorporated by reference, see

§ 170.2). (14) Conduct quality assurance reviews for each assessment, including observations of the Assessment Team's conduct and management of CMMC assessment processes. (15) Ensure that all Level 2 certification assessment activities are performed on the information system within the CMMC Assessment Scope. (16) Maintain all facilities, personnel, and equipment involved in CMMC activities that are in scope of their Level 2 certification assessment and comply with all security requirements and procedures as prescribed by the Accreditation Body. (17) Ensure that all assessment data and information uploaded into the CMMC instantiation of eMASS assessment data is compliant with the CMMC assessment data standard as set forth in eMASS CMMC Assessment Import Templates on the CMMC eMASS website: <https://cmmc.emass.apps.mil> . This system is accessible only to authorized users. (18) Issue Certificates of CMMC Status to OSCs in accordance with the Level 2 certification assessment requirements set forth in § 170.17 , that include, at a minimum, all industry CAGE codes associated with the information systems addressed by the CMMC Assessment Scope, the C3PAO name, assessment unique identifier, the OSC name, and the CMMC Status date and level. (19) Address all OSC appeals arising from Level 2 certification assessment activities. If the OSC or C3PAO is not satisfied with the result of the appeal either the OSC or the C3PAO can elevate the matter to the Accreditation Body for final determination. (20) Submit assessment appeals, review records, and decision results of assessment appeals to DoD using the CMMC instantiation of eMASS.

the DRBG mechanism. The randomness source can be an entropy source or an RBG. || Reseed | To acquire additional bits that will affect the internal state of the DRBG mechanism. || Secure Channel | A path for transferring data between two entities or components that ensures confidentiality, integrity and replay protection, as well as mutual authentication between the entities or components. The secure channel may be provided using approved cryptographic, physical or procedural methods, or a combination thereof. Sometimes called a trusted channel. || Security Strength | A number associated with the amount of work (that is, the number of operations of some sort) that is required to break a cryptographic algorithm or system in some way. In this Recommendation, the security strength is specified in bits and is a specific value from the set {112, 128, 192, 256}. If the security strength associated with an algorithm or system is S bits, then it is expected that (roughly) 2^S basic operations are required to break it. || Seed | Noun : A string of bits that is used as input to a DRBG mechanism. The seed will determine a portion of the internal state of the DRBG, and its entropy must be sufficient to support the security strength of the DRBG. Verb : To acquire bits with sufficient entropy for the desired security strength. These bits will be used as input to a DRBG mechanism to determine a portion of the initial internal state.

This requirement applies to portable storage devices (e.g., USB memory sticks, digital video disks, compact disks, external or removable hard disk drives). NIST SP 800-111 provides guidance on storage encryption technologies for end user devices. FURTHER DISCUSSION CUI can be stored and transported on a variety of portable media, which increases the chance that the CUI can be lost. When identifying the paths CUI flows through your company, identify devices to include in this requirement. 149 NIST SP 800-171A, p. 43. 150 NIST SP 800-171 Rev. 2, p. 30.

DoD declines to add Approved Publishing Partner (APP) and Approved Training Providers (ATP), or sections to the rule. The CMMC Program defines the requirements for the ecosystem. Specific requirements for publishing and training guidelines are determined by the CAICO and do not require the oversight of the DoD. The CMMC Rule does not use the term Licensed Training Provider (LTP), as the LTPs are not required to be licensed. The acronym ATP means Approved Training Provider which encompasses the same role in the CMMC Ecosystem. The DoD does not intend to further delay implementation of CMMC to provide an 18 to 24-month grace period from the official release of the rule to build curriculum. The DoD has reviewed commenter recommendations and revised the rule as follows: The CMMC rule has been updated to state that the CAICO must be accredited by a U.S. based signatory to ILAC or other relevant IAF mutual recognition arrangements and operate in accordance with ISO/IEC 17011:2017(E). The DoD has removed the term ‘practitioner’ from §-170.10(b)(8) for clarity and changed the term subcontractor to training service support provider. e. CCPs and CCAs Comment: Some comments requested DoD's response to speculations about market forces, competitiveness of the CMMC Certified Professional (CCP) and CMMC Certified Assessment (CCA) roles and career opportunities, assessor burnout, complexity of CMMC ecosystem, and a limited assessor pool. Several comments identified administrative changes or preferred rewording or reordering of the CCP and CCA sections of the ecosystem requirements. For example, two commenters objected to repeating the requirement to meet CoPC and COI requirements for each Ecosystem member in §-170.8.

Another comment requested deletion of the requirement for all documentation and records to be provided in English. One commenter recommended revising proficiency and experience requirements for CCPs, CCAs, and Lead CCAs. Another requested clarification on what requirements govern the certification of a CCA and requested the rule allow the CAICO to establish the certification validity period. One comment recommended all additional assessor certification requirements in § 170.11(b)(6)(ii) be removed from the rule, so that only those prerequisite training requirements identified by the CAICO would apply. Another comment suggested that a requirement prohibiting assessors from use of personally owned IT that is contained in the CCA section at § 170.11 also be added to the C3PAO requirements section at § 170.9. Two commenters objected to the restrictions on CCAs sharing information with people outside the assessment team. (printed page 83123)

(8) Disclosures under emergency circumstances. No No (9) Disclosures to the Congress. No No (10) Disclosures to the GAO. No No (11) Disclosures pursuant to court orders. No No (12) Disclosure to consumer reporting agencies. No No (c)(1) Making disclosure accountings. No No (2) Retaining disclosure accountings. Yes Yes (c)(3) Making disclosure accounting available to the individual. Yes No (c)(4) Informing prior recipients of corrections. Yes Yes (d)(1) Individual access to records. Yes Yes (2) Amending records. Yes Yes (3) Review of the Component's refusal to amend a record. Yes Yes (4) Disclosure of disputed information. Yes Yes (5) Access to information compiled in anticipation of civil action. Yes Yes (e)(1) Restrictions on collecting information. Yes No (e)(2) Collecting directly from the individual. Yes No (3) Informing individuals from whom information is requested. No No (e)(4)(A) Describing the name and location of the system. No No (B) Describing categories of individuals. No No (C) Describing categories of records. No No (D) Describing routine uses. No No (E) Describing records management policies and practices. No No (F) Identifying responsible officials. Yes Yes (e)(4)(G) Procedures for determining if a system contains a record on an individual. Yes Yes (H) Procedures for gaining access. Yes Yes (I) Describing categories of information sources. Yes No (e)(5) Standards of accuracy. No No (e)(6) Validating records before disclosure. No No (e)(7) Records of First Amendment activities. No No (e)(8) Notification of disclosure under compulsory legal process. No No (e)(9) Rules of conduct. No No (e)(10) Administrative, technical, and physical safeguards. No No (11) Notice for new and revised routine uses. Yes Yes (f)(1) Rules for determining if an individual is subject of a record. Yes Yes (f)(2) Rules for handling access requests. Yes Yes (f)(3) Rules for granting access. Yes Yes (f)(4) Rules for amending records. Yes Yes (f)(5) Rules regarding fees. Yes No (g)(1) Basis for civil action. Yes No (g)(2) Basis for judicial review and remedies for refusal to amend. Yes No (g)(3) Basis for judicial review and remedies for other failure to comply. Yes No (g)(4) Basis for judicial review and remedies for other failure to comply. Yes No (g)(5) Jurisdiction and time limits. Yes No (h) Rights of legal guardians. No No (i)(1) Criminal penalties for unauthorized disclosure. No No (2) Criminal penalties for failure to publish. No No (3) Criminal penalties for obtaining records under false pretenses. Yes 1 No (j) Rulemaking requirement. N/A No (j)(1) General exemption for the Central Intelligence Agency. N/A No (j)(2) General exemption for criminal law enforcement records. Yes No (k)(1) Exemption for classified material. N/A No (k)(2) Exemption for law enforcement material. Yes N/A (k)(3) Exemption for records pertaining to Presidential protection. Yes N/A (k)(4) Exemption for statistical records. Yes N/A (k)(5) Exemption for investigatory material compiled for determining suitability for employment or service. Yes N/A (k)(6) Exemption for testing or examination material. Yes N/A

The assessment team may obtain information during an assessment that the organization does not want to disclose publicly. The assessment team has an obligation to safely and securely store and protect the confidentiality of all security assessment related records and information, including limiting access to the individuals that need to know the information. When using, storing, and transmitting information related to the assessment, the assessment team shall follow the guidelines established by the organization in addition to all relevant laws, regulations, and standards regarding the need, protection, and privacy of information. During the authorization decision process, the DAO must evaluate the assessment findings for the issuer and for each issuing facility within the authorization boundary. If the issuer has outsourced some of its services or functions, the DAO must review all relevant assessments and authorizations that have been granted to the external service provider and include them as a part of the overall evaluation of risk to the organization. - . Review - An evaluation of documentation that describes plans, policies, and procedures in order to verify that they are adequate, understood by management and operations personnel, and that they are in accordance with applicable policies, regulations, standards, technical guidelines, and

organizational guidance. - · Interview - a directed conversation with one or more issuer personnel in which both preestablished and follow-on questions are asked, responses documented, discussion encouraged, and conclusions reached. - · Observe - a real-time viewing of PIV processes in operation, including all information system components of the issuer involved in creation, issuance, maintenance, and termination of PIV Cards or Derived PIV Credentials.

Section Name	Description
ISCM Strategy Management	Elements related to the breadth and depth of the ISCM strategy
System Level Strategy	Elements related specifically to ISCM strategy at the system level
ISCM Program Management	Elements related to the design and management of the ISCM program
Control Assessment Rigor	Elements related to the relationship between control assessments and risk
Security Status Monitoring	Elements related to the monitoring of ISCM data and metrics
Common Control Assessment	Elements related to the assessment of common controls
System-Specific Control Assessment	Elements related to the assessment of system-specific controls
ISCM Results Included in Risk Assessment	Elements related to the use of ISCM in risk assessment
Threat Information	Elements related to the awareness and monitoring of cyber threat data
External Service Providers	Elements related to the external hosting of assets
Security-Focused Configuration Management	Elements related to the processes for managing security configurations
Section Name	Description
Impact of Changes to Systems and Environments	Elements related to

- The unbundling of functional requirements from each other and from assurances. - The creation of protection profiles by assembling pre-defined components and elaborating them to specific product targets. - The explicit separation of documentation, process, and evaluation assurance. - Recognition of Ease of Use, Physical Protection, and Flaw Remediation (this > thought to be especially important to retain) as requirements. Identification and authentication must be strengthened. There is too much emphasis on passwords, especially when privacy is not assured by physical means. Passwords alone are insufficient in many cases; provision should be explicit for alternative technology.

3.1.3 Automate Selected Defect Checks... 3.1.3 Automate Selected Defect Checks The main steps to implement automation are described in this section.

(Response) Under §§ 1.337 and 1.345 of this final rule, if you are a nontransporter, you must establish and maintain records to identify the date you received and released food. Food is released when it moves from one covered activity to another covered activity (unless both activities are conducted by the same person). For example, an article of food is released from the manufacturer when it is given to the transporter. The food is released again when the transporter delivers the food to a grocery store. Where the manufacturer transports its own food to the grocery store, however, the food is not released when the manufacturer loads his trucks, but rather when the manufacturer delivers the food to the grocery store. 6. Lot or Code Number/Other Identifier (Comment 108) Several comments state that some products do not have lot numbers (e.g., bulk produce and restaurant foods). The comments state that character/number string on the package may be hard to identify as a lot code; food product with closed lot codes requires deciphering; lot codes may be on nonvisible portions of the packaging or on the invoice; the integrity of the lot code may be compromised or unreadable if the outer packaging is damaged; and this requirement potentially forces the manufacturer either to stop using or to shorten the lot codes, which would be counterproductive to addressing public health concerns in this initiative. Another comment states that the requirement to record lot or code number/other identifier would be time inefficient and time consuming. One comment states the agency should require lot number tracing when information is reasonably available. (Response) FDA recognizes the difficulties in some situations of recording lot/code number or other identifiers of food. FDA has revised the final rule to only require that persons who manufacture, process, and pack food to record lot/code numbers or other identifiers. See §§ 1.337(a)(4) and 1.345(a)(4) of this final rule. Furthermore, this requirement only applies to the extent the information exists. FDA has learned through comments that tracking lot/code numbers or other identifiers throughout the manufacturing/processing and packing of food is not a problem, because in most cases it is currently being done or capable of being done. It is during the transporting, distribution, and holding of food (e.g., from the warehouse distribution centers to

the retail store or restaurant) that such tracking becomes a problem. FDA also learned that the food industry is moving in the direction of being able to track the lot or code number or other identifier throughout the entire food chain, but that the current technology has not made such tracking cost efficient.

. Under this proposal, a regulated entity would be expressly required to review and test the effectiveness of the technology assets and/or technical controls required by the respective implementation specifications of this section at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. f. Section 164.312(e)-Standard: Integrity Improper alteration or destruction of ePHI, even unintentionally, can result in clinical quality problems, including patient safety issues, for a covered entity. [767] Workforce members or business associates may make accidental or intentional changes that improperly alter or destroy ePHI. [768] Data can also be altered or destroyed without human intervention, such as by electronic media errors or failures. [769] It is important to protect ePHI from being compromised, regardless of the source. [770] The current standard for integrity at 45 CFR 164.312(c)(1) requires implementation of policies and procedures, rather than actual deployment of technical controls, to ensure integrity of ePHI. To improve the effectiveness of this standard, the Department proposes to redesignate it as proposed 45 CFR 164.312(e) and modify it for clarity. Under the proposal, a regulated entity would be required to deploy technical controls to protect ePHI from improper alteration or destruction when at rest and in transit and to review and test the effectiveness of such technical controls at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. For example, the adoption of health IT that is certified through the ONC Health IT Certification Program as having the technical capability to verify that the electronically exchanged health information contained within the health IT has not been altered, using a hashing algorithm that meets certain requirements, may contribute to a regulated entity's compliance with the proposed standard for integrity. [771] The Department proposes to remove the implementation specification at 45 CFR 164.312(c)(2) because technical controls to corroborate that ePHI has not been altered or destroyed in an unauthorized manner are commonly built into hardware and protocols today. Thus, it is unnecessary to require a regulated entity to specifically deploy such controls. g. Section 164.312(f)(1)-Standard: Authentication Authentication ensures that a person is in fact who they claim to be before being allowed access to ePHI by providing proof of identity. [772] The Department proposes to redesignate the standard for person or entity authentication at 45 CFR 164.312(d) as 45 CFR 164.312(f)(1) to rename it ·Authentication· to reflect its broad purpose, and to add a paragraph heading to clarify the organization of the regulatory text. Additionally, consistent with our proposals to define (printed page 974)

, to add a paragraph heading to clarify the organization of the regulatory text, and to modify the regulatory text to clarify that a regulated entity would be required to implement written policies and procedures to ·respond to,· rather than ·address,· security incidents. Additionally, we propose to clarify expectations by adding an implementation specification for planning and testing at proposed 45 CFR 164.308(a)(12)(ii)(A) (1) that would require a regulated entity to establish written security incident response plan(s) and procedures documenting how workforce members are to report suspected or known security incidents and how the regulated entity will respond to suspected or known security incidents. [599] Internal reporting is an essential component of security incident procedures. [600] Plans and procedures for (printed page 954) reporting of suspected or known security incidents may address to whom, when, and how such incidents are to be reported. The recipient(s) and the content of such reports, according to such plans and procedures, may vary based on the type of incident and the role of the workforce member making the report. We do not propose to dictate the form, format, or content of such report. Rather, we believe that regulated entities would be best situated to identify the point(s) of contact for their organization (e.g., Chief Information Security Officer, IT security team, business associate engaged to support incident response activities for the regulated entity) for such reports and the type of information they need to determine how to respond to the suspected or known security incident. The proposal to require a regulated entity to establish written security incident response plans and procedures for how it will respond to suspected or known security incidents would align with the enhanced CPG for Third Party Incident Reporting because it would address the procedures for how and when a business associate would report to a covered entity or another business associate known or suspected security incidents, as required by proposed 45 CFR 164.314(a)(2)(i)(C) . [601]

Under proposed 45 CFR 164.308(a)(12)(ii)(A) (2) and (3), the regulated entity would be required to implement written procedures for testing and revising the security incident response plan(s) and then, using those written procedures, review and test its security incident response plans at least once every 12 months and document the results of such tests. The regulated entity would also be required to modify the plan(s) and procedures as reasonable and appropriate, based on the results of such tests and the regulated entity's circumstances. This proposal, if finalized, would include requirements that align with the Department's essential CPG for Basic Incident Planning and Preparedness to have effective responses to and recovery from security incidents. [602]

CIS Control 12 · Network Infrastructure Management Establish, implement, and actively manage (track, report, correct) network devices, in order to prevent attackers from exploiting vulnerable network services and access points. Secure network infrastructure is an essential defense against attacks. This includes an appropriate security architecture, addressing vulnerabilities that are, often times, introduced with default settings, monitoring for changes, and reassessment of current configurations. Network infrastructure includes devices such as physical and virtualized gateways, firewalls, wireless access points, routers, and switches. Default configurations for network devices are geared for ease-of-deployment and ease-of-use · not security. Potential default vulnerabilities include open services and ports, default accounts and passwords (including service accounts), support for older vulnerable protocols, and pre-installation of unneeded software. Attackers search for vulnerable default settings, gaps or inconsistencies in firewall rule sets, routers, and switches and use those holes to penetrate defenses. They exploit flaws in these devices to gain access to networks, redirect traffic on a network, and intercept data while in transmission. Network security is a constantly changing environment that necessitates regular re-evaluation of architecture diagrams, configurations, access controls, and allowed traffic flows. Attackers take advantage of network device configurations becoming less secure over time as users demand exceptions for specific business needs. Sometimes the exceptions are deployed, but not removed when they are no longer applicable to the business's needs. In some cases, the security risk of an exception is neither properly analyzed nor measured against the associated business need and can change over time.

From the NIST SP 800-172 Rev 3 Final Public Draft: · Mission -Essential: The agency that owns the information or information system cannot accomplish its Primary Mission-E ssential Functions (PMEF), as approved in accordance with Presidential Policy Directive NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 40 (PPD-40) National Continuity Policy, within expected timelines without the information or information 2938

The rule adds an Alternate I to the provision at FAR 52.204-16, Commercial and Government Entity (CAGE) Code Reporting, to address that prime contractors shall ensure subcontractors under classified solicitations provide the location of subcontractor performance listed on the DD Form 254 to reflect a corresponding unique CAGE code for each listed location unless the work is being performed at a Government facility, in which case the agency location code shall be used. FAR provision 52.204-16 is used when FAR 52.204-6, Unique Entity Identifier, or 52.204-7, System for Award Management, is used. The provision with its Alternate I is used when the clause 52.204-2, Security requirements is included. The rule also adds a new Alternate I to FAR 52.204-18, Commercial and Government Entity Code Maintenance, that requires prime contractors to ensure that subcontractors maintain their CAGE code(s) throughout the life of the contract when the contract may require access to classified information (unless the contracting agency is not covered by the NISP and has prescribed a clause and alternates that are substantially the same as those at 52.204-2, Security Requirements) and if the provision 52.204-16, Commercial and Government Entity Code Reporting, is used with its Alternate I. The rule also relocates the definition of CAGE code to FAR subpart 2.1, Definitions, from FAR subpart 4.18, since the term is used in multiple FAR sections and clauses. III. Applicability to Contracts at or Below the Simplified Acquisition Threshold (SAT) and for Commercial Items, Including Commercially Available Off-the-Shelf (COTS) Items This proposed rule does not create any new provisions or clauses, nor does it change the applicability of any existing provisions or clauses included in solicitations and contracts valued at or below the SAT, or for commercial items, including COTS items. IV. Executive Order 13771 This rule is not subject to E.O. 13771 , Reducing Regulation and Controlling Regulatory Costs, because this rule is not a significant regulatory action under E.O. 12866 . V. Executive Orders 12866 and 13563 E.O.s 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and,

if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804 . VI. Regulatory Flexibility Act DoD, GSA, and NASA do not expect this rule to have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act,

(d) Address vigorous congressional and public interest in increasing cyber security and information assurance activities through government-industry cooperation. (e) Immediately provide a voluntary framework for DOD and DIB companies to share information to address sophisticated cyber threats that represent an imminent threat to U.S. national security and economic security interests. Until this rule is published as an interim final rule, eligible DIB companies cannot receive USG information about cyber threats and mitigation strategies or share information about cyber incidents that may compromise critical DOD programs and missions. Without this information, eligible DIB companies' ability to protect USG information cannot be fully effective. While this vulnerability remains open, the USG faces an elevated risk that critical program information (printed page 27616) could be compromised, resulting in potential economic losses or damage to U.S. national security. For example, the compromise of such information can significantly diminish return on DIB company and U.S. Government research and development investment and represents a loss of intellectual property that compromises the security and technical advantages of DoD weapons systems. DIB CS/IA activities, including the collection, management and sharing of information for cyber security purposes, support and implement the following national and DoD-specific guidance and authority: information assurance (IA) requirements to establish programs and activities to protect DoD information and DoD information systems, including information and information systems operated and maintained by contractors or others in support of DoD activities (see 10 U.S.C. 2224 ; and the Federal Information Security Management Act (FISMA), codified at 44 U.S.C. 3541 et seq.); critical infrastructure protection responsibilities, in which DoD is the sector specific agency for the DIB sector, (see Homeland Security Presidential Directive 7 (HSPD-7), Critical Infrastructure Identification, Prioritization, and Protection-).

A.3.6. Data Protection 1 access to home networks. They also have robust networking capabilities, giving them utility for a wide range of attacks. Other router product components present their own risks. Backends may aggregate data from one or more customers, making them attractive targets for attackers. Mobile applications may be installed in relatively hostile environments due to malware and other vectors of attack. ISO 31000 [ISO31000] is a foundational resource that developers should use for risk management. NIST's Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy , SP 800-37 Rev. 2 [SP800-37r2] may also be useful guidance for risk management.

Sections 236.4 and 236.5 and 236.7 of this final rule contain information collection requirements. These collection requirements were published in the preamble of the interim final rule that published on May 11, 2012 (77 FR 27617) for public comment. No comments were received on the collection requirements. OMB preapproved the collection requirements and assigned them OMB Controls Numbers 0704-0489 and 0704-0490. (printed page 62435) Executive Order 13132 , Federalism It has been certified that 32 CFR part 236 does not have federalism implications, as set forth in Executive Order 13132 . This rule does not have substantial direct effects on: (a) The States; (b) The relationship between the National Government and the States; or (c) The distribution of power and responsibilities among the various levels of Government. List of Subjects in 32 CFR Part 236 Contracts Security measures Accordingly 32 CFR part 236 is revised to read as follows: PART 236-DEPARTMENT OF DEFENSE (DoD)-DEFENSE INDUSTRIAL BASE (DIB) VOLUNTARY CYBER SECURITY AND INFORMATION ASSURANCE (CS/IA) ACTIVITIES 236.1 Purpose. 236.2 Definitions. 236.3 Policy. 236.4 Procedures. 236.5 Cyber security information sharing. 236.6 General provisions. 236.7 DIB participant eligibility requirements. Authority: 10 U.S.C. 2224 ; 44 U.S.C. 3506 ; 44 U.S.C. 3544 . §-236.1 Purpose. Cyber threats to DIB unclassified information systems represent an unacceptable risk of compromise of DoD information and pose an imminent threat to U.S. national security and economic security interests. DoD's voluntary DIB CS/IA program enhances and supplements DIB participants' capabilities to safeguard DoD information that resides on, or transits, DIB

unclassified information systems. § 236.2 Definitions. As used in this part: (a) Attribution information means information that identifies the DIB participant, whether directly or indirectly, by the grouping of information that can be traced back to the DIB participant (e.g., program description, facility locations). (b) Compromise means disclosure of information to unauthorized persons or a violation of the security policy of a system in which unauthorized intentional, or unintentional, disclosure, modification, destruction, loss of an object, or the copying of information to unauthorized media may have occurred. (c) Covered defense information means unclassified information that: (1) Is: (i) Provided by or on behalf of the DoD to the DIB participant in connection with an official DoD activity; or (ii) Collected, developed, received, transmitted, used, or stored by the DIB participant in support of an official DoD activity; and (2) Is: (i) Controlled Technical Information means technical information with military or space application (see 10 U.S.C. 130(c))

3.1.2 | ZTA y el uso de la microsegmentación... 3.1.2 ZTA y el uso de la microsegmentación Una empresa puede optar por implementar una ZTA basada en el emplazamiento de los recursos individuales o grupos de recursos en un único segmento de red protegido por un componente de seguridad denominado puerta de enlace (gateway).

Copies of all initial denials shall be maintained by each DoD Component in a form suitable for rapid retrieval, periodic statistical compilation, and management evaluation. Records denied for any of the reasons contained in § 286.14 (for which no appeal was filed) shall be maintained for a period of 6 years to meet the statute of limitations requirement. (f) Special mail services. The DoD Components are authorized to use registered mail, certified mail, certificates of mailing, and return receipts. However, their use should be limited to instances where it appears advisable to establish proof of dispatch or receipt of FOIA correspondence. The requester shall be notified that they are responsible for the full costs of special services. A commercial delivery service may be used provided the requester asks for such service to receive the requested information in a timelier manner and the requester pays directly for the service. (g) Receipt account. The Treasurer of the United States has established an account for FOIA receipts. This account, receipt account 3210, shall be used for depositing all FOIA receipts, except receipts for ·Working Capital· and non appropriated funded activities. Components are reminded that the account number must be preceded by the appropriate disbursing office two-digit prefix. ·Working Capital· and non-appropriated funded activity FOIA receipts shall be deposited to the applicable fund. All money orders or checks remitting FOIA fees should be made payable to the U.S. Treasurer. § 286.20 Appeals (a) General. If the DoD Component IDA denies a record for any of the reasons contained in § 286.14 the DoD Component shall advise the requester that the decision may be appealed in writing to a designated appellate authority. The Component will further advise the requester that the appeal should be accompanied by a copy of the denial letter. In addition to appeal rights associated with the denial of information, the following are adverse determinations and are subject to appeal: (1) The disapproval of a fee category claim by a requester, the disapproval of a request for waiver or reduction of fees, and a dispute regarding fee estimates. (2) A determination not to grant expedited processing. (3) Not providing a response determination to a FOIA request within the statutory time limits. (4) Any determination found to be adverse in nature by the requester. (b) FOIA/Privacy Act appeals . When denials have been made under the provisions of the Privacy Act and the (printed page 71861) FOIA and the denied information is contained in a Privacy Act system of records, appeals shall be processed under both the Privacy Act and the FOIA. If the denied information is not maintained in a Privacy Act system of records, the appeal shall be processed under the FOIA. (c) Time of receipt

Section 170.12 addresses the roles and responsibilities of a CMMC Certified Instructor (CCI) to teach CMMC assessor candidates. The CAICO trains and tests candidate CCIs per the requirements set forth in § 170.12(b). Candidate CCIs are provided with a list of requirements to obtain and maintain certification, compliance with Accreditation Body policies, work activity exclusions, confidentiality expectations, non-disclosure clause, non-public training related information, forbidden consulting services, and reporting requirements. Section 170.13·CMMC Certified Professional (CCP) Section 170.13 addresses the roles and responsibilities of a CMMC Certified Professional (CCP) required to provide advice, consulting, and recommendations to clients. The CAICO trains and tests candidate CCPs per the requirements set forth in § 170.13(b) with CCP certification issued upon successful completion. A CCP can participate on CMMC Level 2 Certification Assessments with CCA oversight, however CCAs are responsible for making final assessment determinations. A list

of CCP requirements is provided for obtaining and maintaining certification, compliance with Accreditation Body policies, completion of a Tier 3 background investigation or equivalent, sharing assessment specific information, and reporting requirements. (printed page 89065) Section 170.14-CMMC Model Section 170.14 addresses the structure, security requirement contents, organization, sourcing, and numbering of the security requirements that comprise the CMMC Model. It also provides an overview of the assessment process. The CMMC Model consists of three (3) levels, each containing security requirements taken directly from existing regulations and guidelines. Firstly, §-170.14(2) defines CMMC Level 1 as the 15 requirements listed in the FAR clause 52.204-21(b)(1). Secondly, §-170.14(3) defines CMMC Level 2 as the 110 requirements from the NIST SP 800-171 Rev 2. Lastly, §-170.14(4) defines CMMC Level 3 as 24 selected requirements from the NIST SP 800-172. The CMMC security requirements are organized into domains following the approach taken in NIST SP 800-171 Rev 2. The numbering of the CMMC security requirements, addressed in §-170.14(c)(1), is of the form DD.L#-REQ where the 'DD' is the two-letter domain abbreviation, the 'L#' is the CMMC Level, and the 'REQ' is based directly on the numbering in the source. Assessment criteria for these security requirements, as described in §-170.14(d), is based on security requirement assessment guidance provided in NIST SP 800-171A and NIST SP 800-172A. Section 170.15-CMMC Level 1 Self-Assessment and Affirmation Requirements

IMDs are tiny computing platforms that run firmware in extremely power constrained environments. They offer data storage for static data (such as device information), relatively static data (such as patient identification, medical condition, therapy configuration) and dynamic data (such as recent patient readings and audit logs). IMDs offer wireless access for read and write operations to the data on the IMD (including the firmware) to a variety of stakeholders and roles. Some of the threats to wireless IMDs include device reprogramming, data extraction, data tampering, repeated access attempts and data flooding. Vulnerabilities include unsecured communication channels, inadequate authentication and access control, weak audit mechanisms and meager storage. The resulting risks include patient safety compromise resulting from firmware malfunction or therapy misconfiguration, device unavailability due to battery power depletion, patient privacy loss due to data leakage to unauthorized parties, and inappropriate medical follow-up due to tampering of patient readings. While some cyber threats may be unintentional, various motivations exist for deliberate cyber attacks, such as patient information gathering, negative impact to patient health status, ego satisfaction of the attacker, as well as gaining competitive advantage over another vendor through negative press. Identification of the various data types within an IMD is an essential step in analyzing the security and privacy risks of such devices. Possible data types include firmware (though technically not 'data'), device identification data, patient identification and health condition data, therapy configuration data, patient readings, audit log data, and other data.

IBM RS/6000 CIO AIX Version 4.1.1 IBM RS/6000 PowerPC AJX Version 3.2.5 Product Supplier: International Business Machines Corporation Product: AIX Version 3.2.5 for RISC System/6000 with PTFs: Product Supplier: The Santa Cruz Operation, Inc. Product: SCO UNIX*, Ftelease 3.2, Version 4.2 PCD: SCO UNIX* System V/386 Release 3.2.4 POSIX 1

(the CUI Program) or make exceptions for the categories of CUI or the Designating Agency for the CUI. CMMC requirements apply to DoD contracts that will involve processing, storing, or transmitting of FCI or CUI on any non-Federal information system. (printed page 83119) 13. The CMMC Ecosystem Roles, Responsibilities and Requirements a. Government Comment: Some comments asked how the Department plans to address complaints and concerns from ecosystem stakeholders and the process by which disputes between OSCs and C3PAOs or the CMMC AB are resolved. Two comments wanted the CMMC PMO to document a process for ecosystem stakeholders to register complaints or use of Service Level Agreements to hold the Department accountable to respond. Some asked whether the DoD could be subject to litigation challenging DoD's reliance on the CMMC AB's appeals process to resolve disputes between OSCs and C3PAOs. The commenters asserted resolving such disputes may be an inherently governmental function. One commenter noted that transactions between OSCs and C3PAOs for initiating an assessment are beyond the DoD's authority to regulate, since the DoD is not a party to the transaction. They perceived DoD's indirect oversight of C3PAOs through the CMMC AB as creating conflicts of interest and potential legal liabilities. One commenter requested the DoD modify the rule to state the CMMC PMO is responsible for the assessment and monitoring of the CMMC AB, as well as the CMMC AB's performance of its roles. One commenter noted the ISO/IEC 17011:2017(E) requirements that the CMMC AB must meet and asked why the rule identifies a timeline for compliance

instead of requiring immediate accreditation. One commenter referenced a CMMC-related Request for Information issued prior to CMMC program development to gauge industry's capability to provide the necessary ecosystem accreditation and management functions. They asserted no response was provided to their RFI response. One comment suggested the CMMC PMO should develop a process to act as the authoritative source for assessment interpretations to ensure consistency. One person asked which DoD office authored the rule. Another noted the realignment of the CMMC PMO from OUSD(A&S) to DoD CIO and asked whether this indicated a lack of OUSD(A&S) involvement in the program. One commenter noted that DoD Program Managers and requiring activities have a role in the CMMC Program and suggested that their responsibilities for marking and managing CUI be added to the rule. One commenter wanted to require DIBCAC assessors to complete CCP and CCA training and certification exams through a CAICO approved licensed training provider. Response:

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 Organization-generated alerts are focused on information sources that are external 2391

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. This publication provides a broad overview of the Glossary's design. It describes the methodology, assumptions, and constraints used in the development of the underlying database and associated online user interface application (available at <https://csrc.nist.gov/glossary>). Specific implementation details are out of scope of this publication.

. The key element in determining the applicability of this factor is whether disclosure will inform, or have the potential to inform the public, rather than simply the individual requester or small segment of interested persons. The identity of the requester is essential in this situation in order to determine whether such requester has the capability and intention to disseminate the information to the public. Mere assertions of plans to author a book, researching a particular subject, doing doctoral dissertation work, or indigence are insufficient without demonstrating the capacity to further disclose the information in a manner that will be informative to the general public. Requesters should be asked to describe their qualifications, the nature of their research, the purpose of the requested information, and their intended means of dissemination to the public. (D) The significance of the contribution to public understanding . In applying this factor, the Components must differentiate the relative significance or impact of the disclosure against the current level of public knowledge, or understanding which exists before the disclosure. In other words, will disclosure on a current subject of wide public interest be unique in contributing previously unknown facts, thereby enhancing public knowledge, or will it basically duplicate what is already known by the general public? A decision regarding significance requires objective judgment, rather than subjective determination, and must be applied carefully to determine whether disclosure will likely lead to a significant public understanding of the issue. The Components shall not make value judgments as to whether the information is important enough to be made public. (ii) Disclosure of the information ·is not primarily in the commercial interest of the requester. · Determining ·commercial interest· requires consideration of the following issues: (A) The existence and magnitude of a commercial interest . If the request is determined to be of a commercial interest, the Components should address the magnitude of that interest to determine if the requester's commercial interest is primary, as opposed to any secondary personal or non-commercial interest. In addition to profit-making organizations, individual persons or other organizations may have a commercial interest in obtaining certain records. Where it is difficult to

determine whether the requester is of a commercial nature, the Components may draw inference from the requester's identity and circumstances of the request. The Components are reminded that in order to apply the commercial standards of the FOIA, the requester's commercial benefit must clearly override any personal or non-profit interest. (B) The primary interest in disclosure

From the NIST SP 800-172 Rev 3 Final Public Draft: Security-relevant changes include unauthorized changes to established configuration settings or the unauthorized elevation of NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 system privileges. This requirement is sourced to a control tailored out of the SP 2222

The CSF should be used in conjunction with other resources (e.g., frameworks, standards, guidelines, leading practices) to better manage cybersecurity risks and inform the overall management of information and communications technology (ICT) risks at an enterprise level. The CSF is a flexible framework that is intended to be tailored for use by all organizations regardless of size. Organizations will continue to have unique risks - including different threats and vulnerabilities - and risk tolerances, as well as unique mission objectives and requirements. Thus, organizations' approaches to managing risks and their implementations of the CSF will vary. A CSF Organizational Profile describes an organization's current and/or target cybersecurity posture in terms of the Core's outcomes. Organizational Profiles are used to understand, tailor, assess, prioritize, and communicate the Core's outcomes by considering an organization's mission objectives, stakeholder expectations, threat landscape, and requirements. An organization can then prioritize its actions to achieve specific outcomes and communicate that information to stakeholders. 1. A Current Profile specifies the Core outcomes that an organization is currently achieving (or attempting to achieve) and characterizes how or to what extent each outcome is being achieved. 2. A Target Profile specifies the desired outcomes that an organization has selected and prioritized for achieving its cybersecurity risk management objectives. A Target Profile considers anticipated changes to the organization's cybersecurity posture, such as new requirements, new technology adoption, and threat intelligence trends.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 v Call for Patent Claims 87 Th is public review includes a call for information on essential patent claims (claims whose use would be required for compliance with the guidance or requirements in this Information Technology Laboratory (ITL) draft publication). Such guidance and/or requirements may be directly stated in this ITL Publication or by reference to another publication. This call also includes disclosure, where known, of the existence of pending U.S. or foreign patent applications relating to this ITL draft publication and of any relevant unexpired U.S. or foreign patents. ITL may require from the patent holder, or a party authorized to make assurances on its beh

(F) From subsections (e)(4)(G), (H), and (I) because it will provide protection against notification of investigatory material which might alert a subject to the fact that an investigation of that individual is taking place, and the disclosure of which would weaken the on-going investigation, reveal investigatory techniques, and place confidential informants in jeopardy who furnished information under an express promise that the sources' identity would be held in confidence (or prior to the effective date of the Act, under an implied promise). In addition, this system of records is exempt from the access provisions of subsection (d). (G) From subsection (e)(5) because the requirement that records be maintained with attention to accuracy, relevance, timeliness, and completeness would unfairly hamper the investigative process. It is the nature of law enforcement for investigations to uncover the commission of illegal acts at diverse stages. It is frequently impossible to determine initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. (H) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going investigation. The conduct of a successful (printed page 14774) investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to the individual and record amendment procedures for this record system. (I) From subsection (g) because this system of records should be exempt to the extent that the civil remedies relate to provisions of 5 U.S.C. 552 a from which

this rule exempts the system. (7) System identifier and name. LDIA 0900, Accounts Receivable, Indebtedness and Claims. (i) Exemption. During the course of accounts receivable, indebtedness or claims actions, exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those other systems of records are entered into this system, the DIA hereby claims the same exemptions for the records from those other systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(k)(2) through (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a

(C) Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured electronic protected health information as required by § 164.410. (D) Report to the covered entity activation of its contingency plan under § 164.308(a)(13) without unreasonable (printed page 1020) delay, and in no case later than 24 hours after activation of the contingency plan. (ii) Other arrangements. The covered entity is in compliance with paragraph (a)(1) of this section if it has another arrangement in place that meets the requirements of § 164.504(e)(3). (iii) Business associate contracts with subcontractors. The requirements of paragraphs (a)(2)(i) and (ii) of this section apply to the contract or other arrangement between a business associate and a subcontractor required by § 164.308(b)(1)(ii) in the same manner as such requirements apply to contracts or other arrangements between a covered entity and business associate. (b)(1) Standard: Requirements for group health plans. Except when the only electronic protected health information disclosed to a plan sponsor is disclosed pursuant to § 164.504(f)(1)(ii) or (iii), or as authorized under § 164.508, a group health plan must ensure that its plan documents provide that the plan sponsor will reasonably and appropriately safeguard electronic protected health information created, received, maintained, or transmitted to or by the plan sponsor on behalf of the group health plan. (2) Implementation specifications. The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to do all of the following: (i) Safeguard implementation. Implement the administrative, physical, and technical safeguards that covered entities and business associates are required to implement under §§ 164.308(a), 164.310, and 164.312. (ii) Separation. Ensure that the adequate separation required by § 164.504(f)(2)(iii) is supported by the administrative, physical, and technical safeguards implemented in accordance with paragraph (b)(2)(i) of this section. (iii) Agents. Ensure that any agent to whom it provides this information agrees to implement the administrative, physical, and technical safeguards in accordance with paragraph (b)(2)(i) of this section. (iv) Security incident awareness. Report to the group health plan any security incident of which it becomes aware. (v) Contingency plan activation. Report to the group health plan activation of its contingency plan, adopted in accordance with § 164.308(a)(13) as required by paragraph (b)(2)(i) of this section, without unreasonable delay and in no case later than 24 hours after activation of the contingency plan. § 164.316 Documentation requirements. (a) Standard: Documentation. A covered entity or business associate must do all of the following in written form, which may be electronic, taking into consideration the factors in § 164.306(b):

CIS Safeguard 14.6 · Train Workforce Members on Recognizing and Reporting Security Incidents Train workforce members to be able to recognize a potential incident and be able to report such an incident. Implementation Groups: 1,2,3 Asset Type: data Security Function: protect Parent Control: Security Awareness and Skills Training

(D) From subsections (e)(4)(G) and (H) because this system of records is compiled for investigative purposes and is exempt from the access provisions of subsections (d) and (f). (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NRO will, nevertheless, continue to publish such a notice in broad generic terms as is its current practice. (printed page 14789) (F) Consistent with the legislative purpose of the Privacy Act of 1974, the NRO will grant access to nonexempt material in the records being maintained. Disclosure will be governed by NRO's Privacy Regulation, but will be limited to the extent that the identity of confidential sources will not be compromised; subjects of an investigation of an actual or potential criminal or civil violation will not be alerted to the investigation; the physical safety of witnesses, informants and law enforcement personnel will not be endangered; the privacy of third parties will not be violated; and that the disclosure would not otherwise impede effective law enforcement. Whenever possible,

information of the above nature will be deleted from the requested documents and the balance made available. The controlling principle behind this limited access is to allow disclosures except those indicated above. The decisions to release information from these systems will be made on a case-by-case basis. (5) System identifier and name. QNRO-19, Customer Security Services Personnel Security Files. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and/or (k)(5) from the following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (H) and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5). (iii) Reasons.

discussed above, the Department recognizes that the health care environment has changed in a way that necessitates thorough and frequent review of and updates to documentation. By proposing to specify how often documentation must be updated, the Department would clarify that we expect regulated entities to review and update their documentation at regular intervals, in addition to doing so in response any changes to a security measure. Cybersecurity and data protection is an evolving process, which makes formal, updated, and detailed documentation imperative for data protection. By reviewing and updating its documentation, including its written policies and procedures, at least annually and in response to changes to its security measures, a regulated entity should have a full understanding of its implemented security measures and be able to determine which measures should be updated to protect the confidentiality, integrity, and availability of ePHI. As discussed above and consistent with the proposed changes to 45 CFR 164.306, the Department is proposing to remove the term "required" from 45 CFR 164.316(b)(1) through (3). 4. Request for Comment The Department requests comment on the foregoing proposals, including any benefits, drawbacks, or unintended consequences. We also request comment on the following consideration in particular: a. Whether it would be appropriate to require regulated entities to review and update documentation for security measures at least once every 12 months. If not, please explain. b. Whether it is clear that 45 CFR 164.316 provides regulated entities with directions on when and how they are to document all security measures across all safeguard requirements. If not, please explain. c. Whether it is feasible for regulated entities to document all of the actions, activities, and assessments required by the Security Rule as proposed at 45 CFR 164.316(a)(2). If not, please explain. I. Section 164.318 Transition Provisions 1. Current Provisions and Issues To Address Section 164.318 established the compliance dates for the initial implementation of the security standards for health plans, health care clearinghouses, and health care providers in 2005 and 2006. [866] Covered entities have been required to comply with the security standards for almost 20 years, and the initial implementation of the security standards is no longer applicable. Because of this, the Department believes that these provisions are no longer necessary. 2. Proposal The Department proposes to remove the information in 45 CFR 164.318 and replace the language with provisions for transitioning to the revised Security Rule, should the proposals included in this NPRM be adopted.

(Response) The provisions describe the specific information a covered entity must keep, but do not specify the form or type of system in which those records must be maintained. As stated in both the proposed and final § 1.330, these provisions do not require duplication of existing records if those records contain all of the information required by subpart J of this final rule. If a person subject to these provisions keeps records of all of the information as required by subpart J in compliance with other Federal, State, or local regulations, or for any other reason, e.g., as a result of its own business practices, then those records may be used to meet these requirements. Such records may include, but are not limited to, purchase orders, bills of lading, invoices, and shipping documents. Moreover, entities do not have to keep all of the information required by this final rule in one set of records. If they have records containing some of the required information, they may keep those existing records and keep, either separately or in a combined form, any new data required by this final rule. There is no obligation to create an entirely new record or compilation of records

containing both existing and new information, even if the records containing some of the required information were not created at the time the food was received or released. Our intent is to have as little impact as possible on current recordkeeping practices if those records can meet the requirements of these regulations. FDA received numerous comments, as discussed further in section III.G of this document on “Can existing records satisfy the requirements of this subpart?” that agreed with this approach to not specify the type and format of the records and to allow flexibility to use existing recordkeeping systems. In addition, comments state that individual companies are in a better position to decide in what format records are needed based on knowledge of applicable business practices and cost structures. For these reasons, FDA has not included a model form in this final rule. (Comment 2) Several comments state that the food industry has repeatedly demonstrated the ability to identify and remove product from grocery store shelves very quickly. The comments suggest that the diversion of substantial resources that would be necessary to implement the agency's proposed regulations would not further food security, but instead would diminish the overall efficiency of the food distribution system, which is necessary to serve food safety and security needs and commercial purposes.

21 U.S.C. 348(h)(6)). Person includes individual, partnership, corporation, and association. Recipe means the formula, including ingredients, quantities, and instructions, necessary to manufacture a food product. Because a recipe must have all three elements, a list of the ingredients used to manufacture a product without quantity information and manufacturing instructions is not a recipe. Restaurant means a facility that prepares and sells food directly to consumers for immediate consumption. “Restaurant” does not include facilities that provide food to interstate conveyances, central kitchens, and other similar facilities that do not prepare and serve food directly to consumers. (1) Facilities in which food is directly provided to humans, such as cafeterias, lunchrooms, cafes, bistros, fast food establishments, food stands, saloons, taverns, bars, lounges, catering facilities, hospital kitchens, day care kitchens, and nursing home kitchens, are restaurants. (2) Pet shelters, kennels, and veterinary facilities in which food is directly provided to animals are restaurants. Transporter means a person who has possession, custody, or control of an article of food in the United States for the sole purpose of transporting the food, whether by road, rail, water, or air. Transporter also includes a foreign person that transports food in the United States, regardless of whether that foreign person has possession, custody, or control of that food for the sole purpose of transporting that food. Transporter's immediate previous source means a person from whom a transporter received food. This source can be either another transporter or a nontransporter. Transporter's immediate subsequent recipient means a person to whom a transporter delivered food. This recipient can be either another transporter or a nontransporter. You means a person subject to this subpart under § 1.326. § 1.329 Do other statutory provisions and regulations apply? (a) In addition to the regulations in this subpart, you must comply with all other applicable statutory provisions and regulations related to the establishment and maintenance of records for foods except as described in paragraph (b) of this section. For example, the regulations in this subpart are in addition to existing recordkeeping regulations for low acid canned foods, juice, seafood, infant formula, color additives, bottled water, animal feed, and medicated animal feed. (b) Records established or maintained to satisfy the requirements of this subpart that meet the definition of electronic records in § 11.3(b)(6) (21 CFR 11.3 (b)(6)) of this chapter are exempt from the requirements of part 11 of this chapter. Records that satisfy the requirements of this subpart but that are also required under other applicable statutory provisions or regulations remain subject to part 11 of this chapter. § 1.330 Can existing records satisfy the requirements of this subpart?

(A) The contractor will provide a copy of the authorization to the CSA. (B) The CSA will provide a copy of the authorization to the Department of State Directorate of Defense Trade Controls (DDTC). (e) International visits. (1) General. (i) The contractor will establish procedures to monitor international visits by their employees and visits or assignments of foreign nationals to the contractor location. Doing so will ensure that the disclosure of, and access to, classified export-controlled articles related to classified information are limited to those that are approved by an export authorization. (ii) Contractors cannot use visit authorizations to employ or otherwise acquire the services of foreign nationals that require access to export-controlled information. An export authorization is required for such situations. (2) International visits by U.S. contractor employees. (i) Types and purpose of international visits. (A) One-time visits. A visit for a single, short-term occasion (normally 30 days or fewer) for a specified purpose. (B) Recurring visits. Intermittent, recurring visits over a specified period of time, normally up to one year in

duration, in support of a government-approved arrangement, such as an agreement, contract, or license. By agreement of the governments, the term of the authorization may be for the duration of the arrangement, subject to annual review, and validation. (C) Long-term visits. A single visit for an extended period of time, normally up to one year, in support of an agreement, contract, or license. (D) Emergency visits. A visit related to a specific government-approved contract, international agreement or announced request for proposal, and failure to make the visit could be reasonably expected to seriously jeopardize performance on the contract or program, or result in the loss of a contract opportunity. (ii) Requests for visits. Visit requests are necessary to make administrative arrangements and disclosure decisions and obtain security assurances. (A) Many foreign governments require the submission of a visit request for all visits to a government facility or a cleared contractor facility, even though classified information may not be involved. They may also require that the requests be received a specified number of days in advance of the visit. (B) The contractor can obtain information pertaining to the visit (printed page 83353) requirements of other governments and the NATO from the CSA. The contractor must obtain an export authorization if classified export controlled articles or technical data is to be disclosed or if information to be divulged is related to a classified USG program, unless the disclosure of the information is covered by other agreements, authorizations, or exemptions. (iii) Request format.

Per FAR clause 52.204-XX, Controlled Unclassified Information, upon request, a contractor shall submit the description of the system security plan required by NIST SP 800-171, Revision 2, (and NIST SP 800-172, when applicable) and any associated plans of action for any planned implementations or mitigations to the Government to demonstrate the contractor's implementation or planned implementation of the security requirements. Requests for the system security plan are expected to be rare or limited to, for example, instances where the Government is dealing with a CUI incident, or an agency determines that it is necessary to verify a contractor's system security plan based on the criticality of a program and the CUI being handled on the contractor's information system. Comply with any additional security requirements identified in the Requirements Document. In addition to the security requirements outlined in the SF XXX and the CUI clause, the requirements document in the contract may require the Contractor to comply with additional security requirements beyond NIST SP 800-171, Revision 2, to address unique requirements to protect CUI Basic at higher than the moderate confidentiality level in accordance with 32 CFR 2002.14(h)(2) . The Contractor shall also implement additional information security requirements it reasonably determines necessary to provide adequate security in a dynamic environment. Comply with Additional Notification Requirements. Unmarked or mismarked CUI is not considered a CUI incident if the mismarking has not resulted in the mishandling or improper dissemination of the information. Per the new solicitation provision and contract clauses, offerors are requested and contractors are required to notify the Contracting Officer Representative or other designated agency official concerning any unmarked or mismarked CUI if discovered. Such occurrences are expected to be rare. Comply with Additional Marking Requirements. To the maximum extent practicable, offerors and contractors are required to identify and mark any proprietary business or contractor-attributable information. The following compliance requirements are attributed only to non-defense contractors and subcontractors that handle CUI, since defense contractors are already required to comply with these requirements pursuant to DFARS clause 252.204-7012: Comply with NIST SP 800-171, Revision 2.

Three comments said the affirmation language needs revision because maintaining perfect scores is not possible and asking individuals to affirm continuous compliance is unreasonable. One commenter voiced apprehension that signing the affirmation statement would make a person criminally liable under the False Claims Act, due to the need for system maintenance to fix things that break. One commenter expressed concern that continuous monitoring by contractors increases cost and burden to stay in compliance and opens companies up to False Claims Act liabilities. One of these commenters recommended DoD rely on representation and self-assessment in lieu of affirmations to indicate that the offeror meets the requirements of the CMMC level required by the solicitation. Two commenters requested clarification on what affirmation entails. Another commenter requested modification to clarify that the Affirming Official will attest only that the requirements are implemented as of the certification date, or proposal submission date, and requested removal of affirmation references to continuous compliance. Two commenters urged the Department to align the annual affirmation timeline with the 3-year assessment timeline to ensure consistency and reduce potential False Claims Act liability. One commenter also incorrectly believed a prime contractor affirmation would be made on behalf of its entire supply chain. Another commenter asked DoD to clarify that an organization may obtain from C3PAOs a limited review of changes made since the last assessment in support of required

affirmations and noted that the DoD or CMMC AB may wish to clarify what supporting evidence is required for annual affirmations. Additionally, the commenter recommended that DoD reconsider the requirements for CMMC Level 1 since these are covered by System for Award Management (SAM). One commenter asked, in reference to POA&M closeout affirmations, if there was no longer an expectation that a C3PAO will confirm the close out of a POA&M. One commenter provided a recommendation to include an executive summary in the affirmation that includes POA&M related metrics as an indicator of an OSA's effective O&M, security, and continuous monitoring activities. Response:

Scoping for CMMC Level 2, as detailed in § 170.19(c), consists of all assets that process, store, or transmit CUI, and all assets that provide security protections for these assets. These assets are fully assessed against the applicable CMMC security requirements identified in § 170.14(c)(3) and following the Level 2 self-assessment procedures in § 170.16(c) or the Level 2 certification assessment procedures in § 170.17(c). In addition, Contractor Risk Managed Assets, which are assets that can, but are not intended to, process, store, or transmit CUI because of security policy, procedures, and practices in place, are documented and are subject to a limited check that may result in the identification of a deficiency, as addressed in table 3 to § 170.19(c)(1). Finally, Specialized Assets, which are assets that can process, store, or transmit CUI but are unable to be fully secured, including: Internet of Things (IoT) devices, Industrial Internet of Things (IIoT) devices, Operational Technology (OT), Government Furnished Equipment (GFE), Restricted Information Systems, and Test Equipment, are documented but are not assessed against other CMMC security requirements, as addressed in table 3 to § 170.19(c)(1). All other assets are out-of-scope and are not considered in the assessment. Scoping for CMMC Level 3, as detailed in § 170.19(d), consists of all assets that can (whether intended to or not) or do process, store, or transmit CUI, and all assets that provide security protections for these assets. The CMMC Level 3 Assessment Scope also includes all Specialized Assets but allows an intermediary device to provide the capability for the Specialized Asset to meet one or more CMMC security requirements, as needed. These assets (or the applicable intermediary device, in the case of Specialized Assets) are fully assessed against the applicable CMMC security requirements identified in § 170.14(c)(4) and following the procedures in § 170.18(c). All other assets are out-of-scope and are not considered in the assessment. If an OSA utilizes an ESP, including a Cloud Service Provider (CSP), that does not process, store, or transmit CUI, the ESP does not require its own CMMC assessment. The services provided by the ESP are assessed as part of the OSC's assessment as Security Protection Assets. Section 170.20 Standards Acceptance Section 170.20 addresses how OSCs that, prior to the effective date of this rule, have achieved a perfect score on a DCMA DIBCAC High Assessment with the same scope as a Level 2 CMMC Assessment Scope, will be given a CMMC Status of Level 2 (C3PAO). Section 170.21 Plan of Action and Milestones Requirements

. However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (C) Portions of this system of records may be exempt from the provisions of 5 U.S.C. 552a(c)(3) ; (d); (e)(1); (e)(4)(G), (H), and (I); and (f). (ii) Authority. 5 U.S.C. 552a(k)(1) and (k)(2) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit individuals to obtain valuable information concerning the nature of the investigation and would present a serious impediment to the orderly conduct of any investigative activities. Such accounting could result in the release of properly classified information which would compromise the national defense or disrupt foreign policy. (B) From subsections (d) and (f) because access to the records would inform individuals of the existence and nature of the investigation; provide (printed page 14766) information that might result in the concealment, destruction, or fabrication of evidence; possibly jeopardize the safety and well-being of informants, witnesses and their families; likely reveal and render ineffectual investigatory techniques and methods and sources of information; and possibly result in the invasion of the personal privacy of third parties. Access could result in the release of properly classified information which could compromise the national defense or disrupt foreign policy. Amendment of the records would interfere with the ongoing investigation and impose an impossible administrative burden by requiring investigations to be continually reinvestigated. (C) From subsection (e)(1) because in the course of the investigation it is not always possible, at least in the early stages of the inquiry, to determine relevance and or necessity as such determinations may only occur after the information has been evaluated. Information may be obtained concerning the actual or potential violation of laws or regulations other than those relating to the

ongoing investigation. Such information should be retained as it can aid in establishing patterns of improper activity and can provide valuable leads in the conduct of other investigations. (D) From subsection (e)(4)(G) and (H) because this system of records is exempt from individual access pursuant to subsections (k)(1) and (k)(2) of the Privacy Act of 1974. (E) From subsection (e)(4)(I) because it is necessary to protect the confidentiality of sources and to protect the privacy and physical safety of witnesses. Although the system is exempt from this requirement, the DON has published a notice in broad, generic terms in the belief that this is all that subsection (e)(4)(I) of the Act requires. (10) System identifier and name. N05300-3, Faculty Professional Files. (i)

(i) A contractor's notification of a third-party request for access to Government data or any associated metadata, or access to information systems with access to Government data or any associated metadata (52.239-YY(i)(3)); (j) A contractor's request to publish or disclose the details of any safeguards either designed or developed by the contractor under the contract, or otherwise provided by the Government (52.239-YY(i)(4)); (k) A contractor's submission of its operational technology equipment list, when requested by the agency (52.239-YY(k)(3)); and (l) Any other relevant contractor or third-party requests for access or data not covered herein. 39.X04 Contract clauses. When acquiring services to develop, implement, operate, or maintain a FIS, the contracting officer shall insert: (a) The clause at 52.239-YY, Federal Information Systems Using Non-Cloud Computing Services, in solicitations and contracts that use, or are anticipated to use, non-cloud computing services in performance of the contract; and (b) The clause at 52.239-XX, Federal Information Systems Using Cloud Computing Services, in solicitations and contracts that use, or are anticipated to use, cloud computing services in performance of the contract. PART 52. SOLICITATION PROVISIONS AND CONTRACT CLAUSES 19. Amend section 52.204-9 by: a. Revising the date of the clause; and b. Removing from paragraph (d) "Federally-controlled information" and adding "Federal information" in its place. The revision reads as follows: 52.204-9 Personal Identity Verification of Contractor Personnel. * * * * * Personal Identity Verification of Contractor Personnel (DATE) * * * * * 20. Amend section 52.212-5 by: a. Revising the date of the clause; b. Redesignating paragraphs (b)(63) through (64) as paragraphs (b)(65) through (66); c. Adding new paragraphs (b)(63) and (64); d. Redesignating paragraph (e)(1)(xxiv) as paragraph (e)(1)(xxvi); e. Adding new paragraphs (e)(1)(xxiv) and (xxv); f. In Alternate II by: i. Revising the date of Alternate II; ii. Redesignating paragraphs (e)(1)(ii)(W) as paragraph (e)(1)(ii)(Y); and adding new paragraphs (e)(1)(ii)(W) and (X); The revisions and additions read as follows: 52.212-5 Contract Terms and Conditions Required To Implement Statutes or Executive Orders-Commercial Products and Commercial Services. * * * * * Contract Terms and Conditions Required To Implement Statutes or Executive Orders-Commercial Products and Commercial Services (DATE) * * * * * (b) * * * _ (63) 52.239-YY Federal Information Systems Using Non-Cloud Computing Services (DATE) (E.O. 14028 and 15 U.S.C. 278g-3e). _ (64) 52.239-XX Federal Information Systems Using Cloud Computing Services (DATE) (E.O. 14028). * * * * * (e)(1) * * * (xxiv) 52.239-YY Federal Information Systems Using Non-Cloud Computing Services (DATE) (E.O. 14028 and 15 U.S.C. 278g-3e). (xxv) 52.239-XX Federal Information Systems Using Cloud Computing Services (DATE) (E.O. 14028). * * * * * Alternate II. (DATE) * * * (e)(1) * * * (ii) * * *

(5) Appropriate administrative, technical, and physical safeguards shall be established, based on the media (e.g., paper, electronic, etc.) involved, to ensure the security of the records and to prevent compromise or misuse during storage, transfer, or use, including working at authorized alternative worksites. (c) No record shall be maintained on how an individual exercises rights guaranteed by the First Amendment to the Constitution, except as follows: (1) When specifically authorized by statute; (2) When expressly authorized by the individual on whom the record is maintained; or (3) When the record is pertinent to and within the scope of an authorized law enforcement activity. (d) Notices shall be published in the Federal Register and reports shall be submitted to Congress and the Office of Management and Budget, in accordance with, and as required by, 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R, as to the existence and character of any system of records being established or revised by the DoD Components. Information shall not be collected, maintained, used, or disseminated until the required publication and review requirements, as set forth in 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R, are satisfied. (e) Individuals shall be permitted, to the extent authorized by 5 U.S.C. 552a and DoD 5400.11-R, to: (1) Determine what records pertaining to them are contained in a system of records. (2) Gain access to such records and obtain a copy of those records or a part thereof. (3) Correct or amend such records once it has been determined that the records are not accurate, relevant, timely, or

complete. (4) Appeal a denial of access or a request for amendment. (f) Disclosure of records pertaining to an individual from a system of records shall be prohibited except with the consent of the individual or as otherwise authorized by 5 U.S.C. 552a, DoD 5400.11-R, and DoD 5400.7-R. When disclosures are made, the individual shall be permitted, to the (printed page 18761) extent authorized by references 5 U.S.C. 552a and/or DoD 5400.11-R, to seek an accounting of such disclosures from the DoD Component making the release. (g) Disclosure of records pertaining to personnel of the National Security Agency, the Defense Intelligence Agency, the National Reconnaissance Office, and the National Geospatial-Intelligence Agency shall be prohibited to the extent authorized by Public Law 86-36 (1959) and 10 U.S.C. 424. Disclosure of records pertaining to personnel of overseas, sensitive, or routinely deployable units shall be prohibited to the extent authorized by 10 U.S.C. 130b. Disclosure of medical records is prohibited except as authorized by DoD 6025.18-R. [6] (h) Computer matching programs between the DoD Components and the Federal, State, or local governmental agencies shall be conducted in accordance with the requirements of 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R.

provide required technical support. - Insider threats: Insider threats come from people within the organization who have internal information and may have the privileges needed to access the HPC system. Insider threats can be classified into accidental/unintentional threats and malicious/intentional threats. Unintentional threats come from the unintended side effects of normal actions and activity. In contrast, a malicious insider may intentionally upload malicious code into the HPC system.

(C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (D) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7), but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (E) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(4)(G) and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(1), (k)(2), (k)(5), and (k)(7). (iii) Reasons. Granting individuals access to information collected and maintained in this system of records could interfere with orderly investigations; result in the disclosure of classified material; jeopardize the safety of informants, witnesses, and their families; disclose investigative techniques; and result in the invasion of privacy of individuals only incidentally related to an investigation. Material will be screened to permit access to unclassified information that will not disclose the identity of sources who provide the information to the Government under an express or implied promise of confidentiality. (13) System identifier and name. N05520-4, NCIS Investigative Files System. (i) Exemptions. (A) Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principal function any activity pertaining to the enforcement of criminal laws. (B) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (c)(4), (d), (e)(2), (e)(3), (e)(4)(G) through (I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2). (iii) Reasons. (A) Granting individuals access to information collected and maintained by this activity relating to the enforcement of criminal laws could interfere with the orderly investigations, with the orderly administration of justice, and possibly enable suspects to avoid detection or apprehension. Disclosure of this information could result in the concealment, destruction, or fabrication of evidence, and jeopardize the safety and well-being of informants, witnesses and their families, and law enforcement personnel and their families. Disclosure of this information could also reveal and render ineffectual investigative techniques, sources, and methods used by these components and could result in (printed page 14767)

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analysis to advance the development and productive use of information technology. ITL's responsibilities include the development of technical, physical, administrative, and management standards and guidelines for the cost-effective security and privacy of sensitive unclassified information in Federal computer systems. This Special Publication 800-series reports on ITL's research, guidance, and

outreach efforts in computer security and its collaborative activities with industry, government, and academic organizations. The authors, Karen Kent and Tim Grance of the National Institute of Standards and Technology, and Suzanne Chevalier and Hung Dang of Booz Allen Hamilton, wish to thank their colleagues who reviewed drafts of this document and contributed to its technical content. The authors would particularly like to acknowledge Rick Ayers, Wayne Jansen, Peter Mell, and Murugiah Souppaya of NIST, and Adam Feldman, Mike Noblett, and Joseph Nusbaum of Booz Allen Hamilton, for their keen and insightful assistance throughout the development of the document. The authors would also like to express their thanks to security experts Susan Ballou (Office of Law Enforcement Standards), Brian Carrier (Purdue University), Eoghan Casey (Stroz Friedberg, LLC), Duane Crider (Microsoft), Kurt Dillard (Microsoft), Dean Farrington (Wells Fargo Bank), Jessica Reust (Stroz Friedberg, LLC), Marc Rogers (Purdue University), and Miles Tracy (U.S. Federal Reserve System), as well as representatives from the Department of State, for their particularly valuable comments and suggestions.

The E-Government Act of 2002 (Public Law 107-347), passed by the one hundred and seventh Congress and signed into law by the President in December 2002, recognized the importance of information security to the economic and national security interests of the United States. Title III of the E-Government Act, entitled the Federal Information Security Management Act (FISMA) of 2002, tasked NIST with the responsibility of developing security standards and guidelines for the federal government including the development of: FIPS Publication 199, Standards for Security Categorization of Federal Information and Information Systems, approved by the Secretary of Commerce in February 2004, is the first of two mandatory security standards required by the FISMA legislation. 2 FIPS Publication 200, the second of the mandatory security standards, specifies minimum security requirements for information and information systems supporting the executive agencies of the federal government and a risk-based process for selecting the security controls necessary to satisfy the minimum security requirements. This standard will promote the development, implementation, and operation of more secure information systems within the federal government by establishing minimum levels of due diligence for information security and facilitating a more consistent, comparable, and repeatable approach for selecting and specifying security controls for information systems that meet minimum security requirements. The minimum security requirements cover seventeen security-related areas with regard to protecting the confidentiality, integrity, and availability of federal information systems and the information processed, stored, and transmitted by those systems.

(i) Prior to taking any action to downgrade or declassify information, the contractor will seek guidance from the GCA. If the GCA approves such action, the contractor will cancel all old classification markings with the new markings substituted, whenever practical. For documents, at a minimum the outside of the front cover, the title page, the first page, and the outside of the back will reflect the new classification markings, or include the designation UNCLASSIFIED. The contractor will re-mark other material by the most practical method for the type of material involved to ensure that it is clear to the holder what level of classification is assigned to the material. (ii) When the GCA notifies contractors of downgrading or declassification actions that are contrary to the markings shown on the material, the contractor will re-mark material to indicate the change and notify other holders if further dissemination was made. The contractor will mark the material to indicate the: (A) Authority for the action. (B) Date of the action. (C) Identity and position of the individual taking the action. (2) If the volume of material is such that prompt re-marking of each classified item cannot be accomplished without unduly interfering with operations, the contractor may attach a downgrading and declassification notice to the inside of the file drawers or other storage container instead of the re-marking otherwise required. (3) When such documents or materials are withdrawn from the container solely for transfer to another container, or when the container is transferred from one place to another, the transfer may be made without re-marking if the notice is attached to the new container or remains with each shipment. (4) For the purpose of paragraphs (i)(2) and (i)(3) in this section, the contractor must include in the downgrading and declassification notice: (i) The authority for the downgrading or declassification action. (ii) The date of the action. (iii) The storage container to which it applies. (j) Upgrading action. (1) When the contractor receives notice from the GCA to upgrade material to a higher level; for example, from CONFIDENTIAL to SECRET, the contractor will: (i) Immediately enter the new markings on the material according to the notice to upgrade, and strike through all the superseded markings. (ii) Enter the authority for and the date of the upgrading action on the material. (iii) Ensure all records affected are stored at the appropriate level of security,

including digital networks and systems. Upgrades requiring network or system adjustment will be coordinated with the GCA to mitigate or account for impact on the execution of the contract. (2) The contractor will notify all holders to whom they disseminated the material. The contractor will not mark the notice as classified unless it contains additional information warranting classification.

1. the results of a self-assessment of the OSA's implementation of the basic safeguarding requirements set forth in § 170.15 associated with the contractor information system(s) used in performance of the contract; and 2. an initial affirmation of compliance, and then annually thereafter, an affirmation of continued compliance as set forth in § 170.22. 3. the Level 1 self-assessment cost burden will be addressed as part of the 48 CFR part 204 CMMC Acquisition final rule. Level 2 Self-Assessment Level 2 self-assessment requires compliance with the security requirements set forth in NIST SP 800-171 R2 to protect CUI. CMMC Level 2 does not add any additional security requirements to those identified in NIST SP 800-171 R2. OSAs will submit the following information in SPRS: 1. the results of a self-assessment of the OSA's implementation of the NIST SP 800-171 R2 requirements set forth in § 170.16 associated with the covered contractor information system(s) used in performance of the applicable contract. 2. an initial affirmation of compliance, and, if applicable, a POA&M closeout affirmation, and then annually thereafter, an affirmation of continued compliance set forth in § 170.22. 3. the Level 2 self-assessment cost burden will be addressed as part of the 48 CFR part 204 CMMC Acquisition final rule. Level 2 Certification Assessment Level 2 certification assessment requires compliance with the security requirements set forth in § 170.17 to protect CUI. CMMC Level 2 does not add any additional security requirements to those selected in NIST SP 800-171 R2. A Level 2 certification assessment of the applicable contractor information system(s) provided by an authorized or accredited C3PAO is required to validate implementation of the NIST SP 800-171 R2 security requirements prior to award of any prime contract or subcontract and exercise of option. The C3PAO will upload the Level 2 certification assessment results in the CMMC instantiation of eMASS which will feed the information into SPRS. OSCs will submit in SPRS an initial affirmation of compliance, and, if necessary, a POA&M closeout affirmation, and then annually following the Final CMMC Status Date, an affirmation of continued compliance as set forth in § 170.22. The Level 2 certification assessment cost burdens are included in this part (printed page 83174) with the exception of the requirement for the OSC to upload the affirmation in SPRS that is included in the 48 CFR part 204 CMMC Acquisition final rule and an update to DFARS collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements . Additionally, the information collection reporting requirements for the CMMC instantiation of eMASS are included in a separate ICR for this part and cover only those requirements pertaining to the CMMC process. Level 3 Certification Assessment

As stated in § 170.14(c), CMMC Level 1 requirements are found in FAR clause 52.204-21, CMMC Level 2 requirements are found in NIST SP 800-171 R2, and CMMC Level 3 requirements are a selected subset of NIST SP 800-172 Feb2021 requirements as specified in the 32 CFR part 170 CMMC Program rule in table 1 of § 170.14. NIST SP 800-171A Jun2018 provides authoritative procedures for assessing NIST SP 800-171 R2 security requirements and the CMMC Level 2 Assessment Guide provides additional guidance for assessing CMMC Level 2 security requirements. Both documents are referenced in the 32 CFR part 170 CMMC Program rule, at §§ 170.16(c) and 170.17(c). It is recommended that an OSA develop a SSP as a best practice at Level 1, however, it is not required for a CMMC Level 1 self-assessment. A CMMC assessment does not include Non-Federal Organization (NFO) controls from table E in NIST SP 800-171 R2 nor the DFARS clause 252.204-7021 flow down and reporting requirements. DoD concurs that CMMC provides no mechanism for addressing insider threats posed by political divisions in Congress. However, insider threat in general is addressed in the following CMMC security requirements: AT.L2-3.2.3-Insider Threat Awareness; AC.L2-3.1.7-Privileged Functions; PS.L3-3.9.2e-Adverse Information. b. Transition to Future NIST Requirements Comment: Many commenters raised concerns about the CMMC Proposed Rule's citation of a specific version of a relevant baseline document, i.e., NIST SP 800-171 R2. The expressed concerns focused mainly on a perceived potential for a timing conflict between the NIST revision requirements based on DFARS clause 252.204-7012 (revision in effect at time of solicitation) and this CMMC Program rule which specifies NIST SP 800-171 R2. Commentors provided a variety of differing suggestions to address these concerns. Some commenters recommended that no revision number be included, while others recommended citing Revision 3 rather than Revision 2. Others recommended delaying the CMMC Program. Some recommended changing DFARS clause 252.204-7012 or issuing a class deviation to address

differences between the NIST revisions cited. Those that recommended citing to Revision 3 noted that to do otherwise could delay compliance with Revision 3 beyond NIST's anticipated finalization of that publication. Commenters noted that the criteria defined in guidance explaining how to assess against NIST requirements (i.e., NIST SP 800-171A Jun2018) does not identify a revision number for the NIST SP 800-171 requirements to which they apply. In addition to the comments about NIST (printed page 83144) SP 800-171 R2 and NIST SP 800-171 Revision 3, some commenters questioned how DoD would implement or how long the DoD would allow for transitioning to each future version of NIST standards once approved.

Contractors will be responsible for safeguarding classified information in their custody or under their control, with approval for such storage of classified information by the applicable CSA. Individuals are responsible for safeguarding classified information entrusted to them. Contractors will provide the extent of protection to classified information sufficient to reasonably protect it from loss or compromise. (1) Oral discussions. Contractors will ensure that all cleared personnel are aware of the prohibition against discussing classified information over unsecured telephones, in public conveyances or places, or in any other manner that permits interception by unauthorized persons. (2) End of day security checks. (i) Contractors that store classified material will establish a system of security checks at the close of each working day to verify that all classified material and security repositories have been appropriately secured. (ii) Contractors that operate multiple work shifts will perform the security checks at the end of the last working shift in which classified material was removed from storage for use. The checks are not required during continuous 24-hour operations. (3) Perimeter controls. (i) Contractors authorized to store classified material will establish and maintain a system to deter and detect unauthorized introduction or removal of classified material from their facility without proper authority. (ii) If the unauthorized introduction or removal of classified material can be reasonably prevented through technical means (e.g., an intrusion detection system), which are encouraged, no further controls are necessary. The contractor will provide appropriate authorization to personnel who have a legitimate need to remove or transport classified material for passing through designated entry or exit points. (iii) The contractor will: (A) Provide appropriate authorization to personnel who have a legitimate need to remove or transport classified material for passing through designated entry or exit points. (B) Conspicuously post notices at all pertinent entries and exits that persons who enter or depart the facility are subject to an inspection of their personal, except under circumstances where the possibility of access to classified material is remote. (C) Limit inspections to buildings or areas where classified work is being performed. (D) Establish the extent, frequency, and location of inspections in a manner consistent with contractual obligations and operational efficiency. The contractor may use any appropriate random sampling technique. (E) Seek legal advice during the formulation of implementing procedures. (F) Submit significant problems pertaining to perimeter controls and inspections to the CSA. (iv) Contractors will develop procedures for safeguarding classified material in emergency situations. (printed page 83340) (A) The procedures should be as simple and practical as possible and adaptable to any type of emergency that may reasonably arise.

(2) A widely used exception to requests for information from local and state government agencies and Federal agencies not within the DOD is the routine use exception to the Privacy Act. (3) The most widely used exception to requests for information from other DOD components is the 'intra-agency need to know' exception to the Privacy Act. Officers and employees of the DOD who have an official need for the records in the performance of their official duties are entitled to Privacy Act protected information. Rank, position, or title alone does not authorize access to personal information about others. An official need for the information must exist before disclosure. (4) For the purposes of disclosure and disclosure accounting, the Department of Defense (DOD) is considered a single agency. (c) Disclosures under AR 25-55, the Freedom of Information Act (FOIA) Program. (1) Despite Privacy Act protections, all records must be disclosed if the Freedom of Information Act (FOIA) requires their release. The FOIA requires release unless the information is exempted by one or more of the nine FOIA exemptions. (2) Required release under the FOIA. The following are examples of personal information that is generally not exempt from the FOIA; therefore, it must be released to the public, unless covered by paragraphs (d)(2) and (d)(3) of this section. The following list is not all inclusive: (i) Military Personnel- (A) Rank, date of rank, active duty entry date, basic pay entry date, and gross pay (including base pay, special pay, and all allowances except Basic Allowance for Housing); (B) Present and past duty assignments, future stateside assignments; (C) Office/unit name, duties address and telephone number (DOD policy may

require withholding of this information in certain circumstances); (D) Source of commission, promotion sequence number, military awards and decorations, and professional military education; (E) Duty status, at any given time; (F) Separation or retirement dates; (G) Military occupational specialty (MOS); (H) Active duty official attendance at technical, scientific or professional meetings; and (I) Biographies and photos of key personnel (DOD policy may require withholding of this information in certain circumstances). (ii) Federal civilian employees- (A) Present and past position titles, occupational series, and grade; (B) Present and past annual salary rates (including performance awards or (printed page 24505) bonuses, incentive awards, merit pay amount, Meritorious or Distinguished Executive Ranks, and allowances and differentials); (C) Present and past duty stations; (D) Office or duty telephone number (DOD policy may require withholding of this information in certain circumstances); and

The Department anticipates that the most significant direct costs on State and local governments would be for conducting a Security Rule compliance audit; notifying covered entities or business associates, as applicable, upon activation of a contingency plan; notifying covered entities of changes or termination of workforce members' access to ePHI; deploying MFA; removing extraneous software; and penetration testing; providing or obtaining verification of business associates' compliance with technical safeguards; updating health plan documents; updating policies and procedures; and updating workforce training. However, the costs involved can be attributed to the statutory requirements of the Administrative Simplification provisions of HIPAA and would be similar in kind to those borne by non-government-operated regulated entities, which the proposed RIA above addresses in detail. In considering the principles in and requirements of E.O. 13132 , the Department believes that these proposed modifications to the Security Rule would not significantly affect the rights, roles, and responsibilities of the States and requests comment on this analysis.

E. Assessment of Federal Regulation and Policies on Families Section 654 of the Treasury and General Government Appropriations Act of 1999 [1031] requires Federal departments and agencies to determine whether a proposed policy or regulation could affect family well-being. If the determination is affirmative, then the Department or agency must prepare an impact assessment to address criteria specified in the law. This proposed rule is expected to strengthen family well-being because it would ensure a baseline of security measures for individuals' PHI, and medical information and decisions based on that information are at the heart of family decision making. If finalized, the provisions in this proposed rule may be carried out only by the Federal Government because it would modify Federal law on cybersecurity in health care, ensuring that American families have confidence that the privacy of their PHI is secured by consistent safeguards, regardless of the State where they are located when health care is provided. Such health care privacy and is vital for individuals who seek or access health care. F. Paperwork Reduction Act of 1995 Under the PRA, [1032] agencies are required to submit to OMB for review and approval any reporting or recordkeeping requirements inherent in a proposed or final rule and are required to publish such proposed requirements for public comment. To fairly evaluate whether an information collection should be approved by the OMB, section 3506(c)(2)(A) of the PRA requires that the Department solicit comment on the following issues: 1. Whether the information collection is necessary and useful to carry out the proper functions of the agency. 2. The accuracy of the agency's estimate of the information collection burden. 3. The quality, utility, and clarity of the information to be collected.

(Comment 73) FDA requested comments on whether persons subject to the proposed rule always or usually know at the time a perishable food is released whether or not it is intended to be processed into nonperishable food. Two comments state that distributors have no way of knowing whether a perishable food will be processed into a nonperishable food by other parties. Buyers do not always disclose how the product will be used and may utilize it in more than one way. Therefore, producers of perishable food will have to retain records for the longer period, if they are held accountable for the further distribution and use of their products as nonperishable food. (Response) FDA agrees with the comments that covered persons may not know at the time they release food if it is intended to be processed into a food that meets the 2-year record retention requirement. FDA clarifies that the retention period depends upon the status of the food at the time you release a food to your immediate subsequent recipient, regardless of whether it is intended or not to be processed into nonperishable food in the future. 12. Pet Food There were no comments on the definition of pet food, however, FDA has decided to include all animal feeds, including pet food, under these regulations. Therefore, there is no longer a need to define the term ·pet food· and FDA has deleted this definition from the final rule. 13. Recipe (Comment 74) Three comments state that the

proposed definition of recipe is internally inconsistent and ambiguous, and request clarification of its precise meaning. One comment characterizes the proposed definition as confusing and nearly nonsensical. The comment suggests that this definition be removed and that instead § 1.362 of this final rule be modified to add, for example, 'Notwithstanding the exclusion of recipes for food from this subpart, all of the ingredients in a food are subject to this subpart.' Four comments state that the provisions in the proposed rule are inconsistent with the protection of recipes required by the Bioterrorism Act. The Bioterrorism Act and accompanying legislative history make it clear that the records authority does not apply to recipes. The comments urge FDA to further clarify that information on both the quantitative and qualitative ingredients in a proprietary formula are not covered by the proposed recordkeeping requirements or by the records access authority. According to the comments, in its ordinary meaning, a 'recipe' includes three elements: The ingredients, the quantities, and the procedure. However, the fundamental element, and the one which in most cases is the most commercially sensitive, is the ingredient list. The comments state that it is not reasonable to define 'recipe' to exclude the list of ingredients to obtain access to the list. The comments state that FDA is exceeding its statutory authority under the Bioterrorism Act.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 INTENDED EFFECT IMPACT ON RISK
EXPECTED RESULTS Delay Increase the amount of time needed for the threat event to result in
adverse impacts. Reduce the likelihood of impact and/or the level of impact. The adversary
achieves the intended effects but not within the intended period. Example: The protection measures
(e.g., access controls, encryption) allocated to resources increase in number and strength based
on resource criticality (calibrated defense-in- depth). The frequency of authentication challenges
varies randomly (temporal unpredictability) and with increased frequency for more critical
resources. The result is that it takes the attacker more time to succeed

A record from a system of records maintained by a DOD component may be disclosed as a routine use to the General Services Administration for the purpose of records management inspections conducted under authority of 44 U.S.C. Sections 2904 and 2906. (12) Disclosure of Information to National Archives and Records Administration Routine Use. A record from a system of records maintained by a DOD component may be disclosed as a routine use to NATIONAL ARCHIVES AND RECORDS ADMINISTRATION for the purpose of records management inspections conducted under authority of 44 U.S.C. sections 2904 and 2906. (13) Disclosure to the Merit Systems Protection Board Routine Use. A record from a system of records maintained by a DOD component may be disclosed as a routine use to the Merit Systems Protection Board, including the Office of the Special Counsel for the purpose of litigation, including administrative procedures, appeals, special studies of the civil service and other merit systems, review of Office of Personnel Management or component rules and regulations, investigation of alleged or possible prohibited personnel practices, including administrative proceedings involving any individual subject of a DOD investigation, and such other functions, promulgated in 5 U.S.C. sections 1205 and 1206, or as may be authorized by law. (14) Counterintelligence Purposes Routine Use. A record from a system of records maintained by a DOD component may be disclosed as a routine use outside the DOD or the U.S. Government for the purpose of counterintelligence activities authorized by U.S. Law or Executive Order or for the purpose of enforcing laws, which protect the national security of the United States. Appendix E to Part 505-Litigation Status Sheet (a) Case Number: The number used by a DA activity for reference purposes; Requester; (b) Document Title or Description: Indicates the nature of the case, such as 'Denial of access', 'Refusal to amend', 'Incorrect records', or other violations of the Act (specify); (c) Litigation: Date complaint filed, Court, and Case File Number; (d) Defendants: DOD component and individual; (e) Remarks: Brief explanation of what the case is about; (f) Court action: Court's finding and disciplinary action (if applicable); and (g) Appeal (If applicable): Date complaint filed, court, case File Number, court's finding, disciplinary action (if applicable). Appendix F to Part 505-Example of a System of Records Notice (a) Additional information and guidance on Privacy Act system of records notices are found in DA PAM 25-51. The following elements comprise a Privacy Act system of records notice for publication in the Federal Register: (b) System Identifier: A0025-55 AHRC-DA FOIA/P Office assigns the notice number, for example, A0025-55, where 'A' indicates 'Army,' the next number represents the publication series number related to the subject matter, and the final letter group shows the system manager's command. In this case, it would be U.S. Army Human Resources Command.

From the NIST SP 800-172 Rev 3 Final Public Draft: on behalf of (an agency) 3026 A situation that occurs when (i) a non-executive branch entity uses or operates an information system or maintains

or collects information for the purpose of processing, storing, or transmitting federal information; and (ii) those activities are not incidental to providing a service or product to the Government. [5] operational technology The hardware, software, and firmware components of a system used to detect or cause changes in physical processes through the direct control and monitoring of physical devices. organization An entity of any size, complexity, or positioning within an organizational structure. [7 , adapted] penetration-resistant architecture An architecture that uses technology and procedures to limit the opportunities for an adver

Theft : Information or physical items are taken without authorization | Threat Event | Vulnerability | Category | Threat Source | Severity | Likelihood | |-----
-----|-----
-----|-----|-----|-----
|-----| | Sensitive information is intercepted from a mobile device | Lack of confidentiality protection or poor cryptography | Confidentiality | Adversarial | EMS: Mod Fire: Low LE: High | High | | Accidental disclosure of information via a shared device or resource | Lack of properly implemented access controls | Confidentiality | Accidental | EMS: Low Fire: Low LE: Mod | Mod | | Individual accesses information and services via a lost or stolen public safety device | Lack of physical access control, lack of user authentication to device | Confidentiality | Adversarial, Human error | EMS: Mod Fire: Low LE: High | Mod | | Pre-installed spyware on device accesses sensitive data | Lack of supply chain controls | Confidentiality | Adversarial | EMS: Mod Fire: Low LE: High | Low | | A denial of service or other technical attack, blocks communications | Protocol not designed to withstand jamming attacks, lack of available spectrum | Availability | Adversarial, Accidental | EMS: High Fire: High LE: High | Mod | Vulnerability: This situation

·Controlling Access to ePHI: For Whose Eyes Only?,· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (July 14, 2021), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-summer-2021/index.html> ; and ·HIPAA Security Rule Facility Access Controls·What are they and how do you implement them?,· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Aug. 2024), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-august-2024/index.html> . Back to Citation 417. ·Letter from NCVHS Chair Jacki Monson (2022), supra note 123, p. 2. Back to Citation 418. Id. at Appendix p. 4. Back to Citation 419. Id. Back to Citation 420. Id at 5. Back to Citation 421. · See 68 FR 8334 , 8336 (Feb. 20, 2003). Back to Citation 422. 68 FR 8334 , 8341 (Feb. 20, 2003); see also Jennifer Cawthra, et al., ·Data Integrity: Identifying and Protecting Assets Against Ransomware and Other Destructive Events,· NIST Special Publication 1800-25A, National Institute of Standards and Technology, U.S. Department of Commerce, p. 1 (Dec. 2020) (·The CIA triad represents the three pillars of information security: confidentiality, integrity, and availability.·), <https://www.nccoe.nist.gov/publication/1800-25/VolA/index.html> . Back to Citation 423. 42 U.S.C. 1320d-2(d)(2)(A) and (C) . Back to Citation 424. ·Section 164.530(c) includes the Privacy Rule standard and implementation specification for safeguarding PHI. It requires covered entities to have in place appropriate administrative, physical, and technical safeguards to protect the privacy of PHI. Additionally, it requires covered entities to reasonably safeguard PHI from intentional or unintentional uses or disclosures that violate the Privacy Rule, and to limit incidental uses or disclosures made pursuant to a permissible or required use or disclosure of PHI. Back to Citation 425. 42 U.S.C. 1320d-2(d) . Back to Citation 426. ·Joint Task Force, ·Managing Information Security Risk: Organization, Mission, and Information System View,· NIST Special Publication 800-39, Appendix B, National Institute of Standards and Technology, U.S. Department of Commerce, p. B-5 (Mar. 2011), <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-39.pdf> . Back to Citation 427. ·Ron Ross, et al., ·Developing Cyber-Resilient Systems: A Systems Security Engineering Approach,· NIST Special Publication 800-160, Volume 2, Revision 1, National Institute of Standards and Technology, U.S. Department of Commerce, p. 1 (Dec. 2021), <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-160v2r1.pdf> . Back to Citation 428. ·Proposed 45 CFR 164.308(a)(12)(i) . Back to Citation 429. ·Proposed 45 CFR 164.308(a)(13)(i) . Back to Citation 430. ·Proposed 45 CFR 164.308(a)(4)(i) . Back to Citation 431. ·Proposed 45 CFR 164.312(h)(1) . Back to Citation 432. · See Letter from NCVHS Chair Jacki Monson (2022), supra

(b) Each such FA between the Government and a DIB participant must comply with and implement the requirements of this part, and will include additional terms and conditions as necessary to effectively implement the voluntary information sharing activities described in this part with individual DIB participants. (c) DoD's DIB CS/IA Program Office is the overall point of contact for the program. The DoD Cyber Crime Center's DoD-DIB Collaborative Information Sharing Environment (DC3/DCISE) is the operational focal point for cyber threat information sharing and incident reporting under the DIB CS/IA program. (d) The Government will maintain a Web site or other Internet-based capability to provide potential DIB participants with information about eligibility and participation in the program, to enable the online application or registration for participation, and to support the execution of necessary agreements with the Government. <http://dibnet.dod.mil/>. (e) Prior to receiving GFI from the Government, each DIB participant shall provide the requisite points of contact information, to include security clearance and citizenship information, for the designated personnel within their company (e.g., typically 3-10 company designated points of contact) in order to facilitate the DoD-DIB interaction in the DIB CS/IA program. The Government will confirm the accuracy of the information provided as a condition of that point of contact being authorized to act on behalf of the DIB participant for this program. (f) GFI will be issued via both unclassified and classified means. DIB participant handling and safeguarding of classified information shall be in compliance with the National Industrial Security Program Operating Manual (NISPOM) (DoD 5220.22-M). The Government shall specify transmission and distribution procedures for all GFI, and shall inform DIB participants of any revisions to previously specified transmission or procedures. (g) Except as authorized in this part or in writing by the Government, DIB participants may use GFI to safeguard covered defense information only on covered DIB systems that are U.S. based; and share GFI only within their company or organization, on a need to know basis, with distribution restricted to U.S. citizens. However, in individual cases, upon request of a DIB participant that has determined that it requires the ability to share the information with a non U.S. citizen, or to use the GFI on a non-U.S. based covered DIB system, and can demonstrate that appropriate information handling and protection mechanisms are in place, the Government may authorize such disclosure or use under appropriate terms and conditions. (h) DIB participants shall maintain the capability to electronically disseminate GFI within the Company in an encrypted fashion (e.g., using Secure/Multipurpose Internet Mail Extensions (S/MIME), secure socket layer (SSL), Transport Layer Security (TLS) protocol version 1.2, DoD-approved medium assurance certificates).

One respondent commented that mundane systems will be over classified by program managers as NSS and that NSS classifications should be reserved to an appropriate level above program manager. This respondent further stated that DoD should take steps to clearly designate systems as 'NSS' and limit the NSS classification. Another respondent stated that because the interim rule incorporates the definition in 44 U.S.C. 3542(b) for 'National Security System', the rule's approach to include the clause in all DoD contracts seems contrary to the legislative intent to limit application to 'covered procurements' as defined in section 806(e)(3) of the FY 2011 NDAA. This respondent further suggested that DoD more narrowly define when contracting officers should include and use this clause (e.g., what types of programs) and create some independent review of contracting activities' decisions to apply the interim rule. Response: In the final rule, the use of the provision and clause is only required when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as defined at DFARS 252.239-7302. In accordance with DoD Instruction 8510.01, Risk Management Framework (RMF) for DoD Information Technology (IT), the requiring activity/program office will designate systems as NSS when it registers them in the DoD Component registry (e.g., DoD Information Technology Portfolio Repository (DITPR)). c. Flowdown Comment: One respondent suggested that because the clause is written to require flowdown to subcontractors regardless of tier, the Government intends to have the right to direct a supplier at any tier to be excluded for a contract. The respondent further stated that this could lead to even greater disruption of a program's supply chain since the loss of a supplier at a remote tier can have ripple effects on all higher-tier contractors and that the potential costs for the delay, disruption, and potential workarounds required to address the situation could be enormous. Failing to address the effects of exclusion of subcontractors almost guarantees that implementation of this rule will result in claims and disputes. Response: The requirement to include the substance of DFARS clause 252.239-7018 in subcontracts has been removed from this final rule. d. Other Applications Comment: One respondent commented that DoD should clarify whether or not the rule applies to embedded processing, whether the rule applies to cloud computing acquisitions, and whether cloud computing acquisitions are

covered procurement actions as a class, since these types of acquisitions are not directly addressed in the interim rule. Response: The rule applies when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system. This includes embedded processing and cloud computing acquisitions if they are NSS.

PS.L2-3.9.1 · Screen Individuals CMMC Assessment Guide · Level 2 | Version 2.13 176 The effective screening of personnel provided by this requirement, PS.L2-3.9.1, improves upon the effectiveness of authentication performed in IA.L2-3.5.2. Example You are in charge of security at your organization. You complete standard criminal background and credit checks of all individuals you hire before they can access CUI [a]. Your screening program follows appropriate laws, policies, regulations, and criteria for the level of access required for each position. Potential Assessment Considerations · Are appropriate background checks completed prior granting access to organizational systems containing CUI [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.9.1 PS.L2-3.9.2 · Personnel Actions CMMC Assessment Guide · Level 2 | Version 2.13 177 PS.L2-3.9.2 · PERSONNEL ACTIONS Ensure that organizational systems containing CUI are protected during and after personnel actions such as terminations and transfers. ASSESSMENT OBJECTIVES [NIST SP 800-171A]159 Determine if: [a] a policy and/or process for terminating system access and any credentials coincident with personnel actions is established; [b] system access and credentials are terminated consistent with personnel actions such as termination or transfer; and [c] the system is protected during and after personnel transfer actions. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]

(Comment 22) One comment asks that FDA clarify in the regulation that domestic grain-handling, feed manufacturing/ingredient or processing facilities dedicated solely to exporting bulk or processed agricultural commodities to other countries are exempt from the recordkeeping requirement unless the commodities, products, or byproducts they handle are introduced into U.S. commerce. The comment states that this clarification would be consistent with the statutory language and FDA's proposed regulations. (Response) The proposed rule applied to persons who manufacture, process, pack, transport, distribute, receive, hold, or import food intended for consumption in the United States, unless the person qualifies for an exclusion in § 1.327. This provision has been changed in the final rule. The Bioterrorism Act does not limit the recordkeeping authority to food that is consumed in the United States. FDA's intent in the proposed rule was to apply the recordkeeping provisions to the full reach of section 306 of the Bioterrorism Act with respect to domestic persons. In contrast, the registration interim final rule that FDA issued under section 305 of the Bioterrorism Act only requires those facilities that manufacture, process, pack, or hold food for consumption in the United States to register. The proposed recordkeeping rule inadvertently added the same qualifier as is in the registration interim final rule: That is, it only applied to food that was intended for consumption in the United States. FDA is removing this qualifying language from the final rule to ensure that all persons that manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States are subject to this final rule unless otherwise exempt. FDA believes this coverage is necessary because foods intended for export could easily be diverted into domestic commerce. In addition, not everyone in the food supply chain may know if the food is intended for consumption in the U.S. or intended solely for export. Therefore, such a limitation in this rulemaking could create holes in a tracing investigation. Further, FDA is concerned that exempting foods intended for export from the recordkeeping regulations could lead to such foods being targeted for tampering and reintroduction into domestic commerce because they would prove more intractable to tracing investigations. (Comment 23) One comment asks whether small growers who provide a raw agricultural commodity to a cooperative must keep records and whether the cooperative must list all of the growers.

Control HA-2: Applications of Cryptographic Techniques, Warsaw, Poland, May 4-8, 2003, Proceedings, ed Biham E (Springer), Lecture Notes in Computer Science, Vol. 2656, pp 491-506. DOI:10.1007/3-540-39200-9_31. Available at https://doi.org/10.1007/3-540-39200-9_31 - [14] Dobraunig C, Mennink B (2024) Generalized Initialization of the Duplex Construction. Applied Cryptography and Network Security -22nd International Conference, ACNS 2024, Abu Dhabi, United Arab Emirates, March 5-8, 2024, Proceedings, Part II, eds Pöpper C, Batina L (Springer), Lecture Notes in Computer Science, Vol. 14584, pp 460-484. DOI:10.1007/978-3-031-54773-7_18 - [15] Barker E, Roginsky A, Davis R (2020) Recommendation for Cryptographic Key Generation, (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-133 Rev. 2.

DOI:10.6028/NIST.SP.800-133r2. - [16] Chakraborty B, Dhar C, Nandi M (2023) Exact Security Analysis of ASCON. Advances in Cryptology -ASIACRYPT 2023 -29th International Conference on the Theory and Application of Cryptology and Information Security, Guangzhou, China, December 4-8, 2023, Proceedings, Part III , eds Guo J, Steinfeld R (Springer), Lecture Notes in Computer Science , Vol. 14440, pp 346-369. DOI:10.1007/978-981-99-8727-6\12 - [17] Lefevre C, Mennink B (2025) Generic Security of the Ascon Mode: On the Power of Key Blinding. Selected Areas in Cryptography -SAC 2024 , eds Eichlseder M, Gams S (Springer Nature Switzerland, Cham), pp 3-32. - [18] Chakraborty B, Dhar C, Nandi M (2024) Tight Multi-user Security of Ascon and Its Large Key Extension. Information Security and Privacy -29th Australasian Conference, ACISP 2024, Sydney, NSW, Australia, July 15-17, 2024, Proceedings, Part I , eds Zhu T, Li Y (Springer), Lecture Notes in Computer Science , Vol. 14895, pp 57-76. DOI:10.1007/978981-97-5025-2\4 - [19] Lefevre C, Mennink B (2025) SoK: Security of the Ascon Modes. IACR Trans Symmetric Cryptol 2025(1):138-210.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY DLO, CRS NIST SP 800-172r3
fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025
ADVERSARY EFFECTS 1023

| [C2M2] | Department of Energy (2021) Cybersecurity Capability Maturity Model . Available at
<https://www.energy.gov/ceser/cybersecurity-capability-maturity- model-c2m2> | |-----|-----

-----| | [CIS] | Center for Internet Security (2021) CIS Controls V8 . Available at
<https://www.cisecurity.org/controls/> | | [COBIT] | Information Systems Audit and Control Association
(ISACA) (2021) Control Objectives for Information and Related Technologies . Available at
<https://www.isaca.org/resources/cobit> | | [IEA] | International Energy Agency (2021) Enhancing Cyber
Resilience in Electricity Systems . Available at <https://webstore.iea.org/download/direct/4359> | |
[ISA] | International Society of Automation (2013) ISA 62443-3-3:2013 - Security for industrial
automation and control systems Part 3-3: System security requirements and security levels (ISA,
North Carolina, USA).

The regulated entity has put in place reasonable and appropriate compensating controls in accordance with the regulated entity's emergency access procedures and contingency plan. As part of its documentation, a regulated entity would need to include the controls that have been deployed, a record of the fact that the compensating controls are in use, and a record indicating that the compensating controls have been reviewed and approved by the regulated entity's Security Official. Proposed 45 CFR 164.312(f)(2)(iv)(B) (3) would require the Security Official to review and document the effectiveness of the compensating controls at least once every 12 months or in response to an environmental or operational change, whichever is more frequent. A determination regarding the effectiveness of the technical controls would be based on their ability to secure the regulated entity's ePHI and its relevant electronic information systems. Last, we propose to add an implementation specification for maintenance at proposed 45 CFR 164.312(f)(2)(v) . Under this proposal, a regulated entity would be expressly required to review and test the effectiveness of the technical controls required by this standard at least once every 12 months or in response to (printed page 977) environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. h. Section 164.312(g)-Standard: Transmission Security Transmission security protects against the interception of ePHI in the communications networks used by regulated entities to transmit ePHI. [789] The Department proposes to redesignate the standard for transmission security as proposed 45 CFR 164.312(g) and to modify the standard consistent with other proposals made elsewhere in this NPRM, as described below. Specifically, we propose to clarify the existing standard by requiring a regulated entity to deploy technical controls to guard against unauthorized access to ePHI in transmission over an electronic communications network. For example, adoption of health IT that is certified through the ONC Health IT Certification Program as having the technical capability to establish a trusted connection using encrypted and integrity message protection or a trusted connection for transport and deploying such capability may contribute to a regulated entity's compliance with the proposed standard for transmission security. [790] These proposed changes are consistent with the Department's proposals to replace ·implement· with ·deploy· in the context of technical safeguards to differentiate between implementation of a written policy or procedure and deployment of technical controls.

The requirement to ·provide all documentation and records in English· refers to official information that would be provided to the CMMC Assessor and Instructor Certification Organization (CAICO) or the DoD. The terms do not pertain to all materials used in the delivery of a course. The DoD disagreed with the recommendation to delete the § 170.12(b)(7) requirement for keeping CMMC training records and information confidential. ·Training activities· do not include course material. The example in § 170.12(b)(7) (student records) makes clear the type of data covered by the rule.

2. Time Limits and Other Constraints Comment: One comment recommended that the CAICO, instead of the DoD, determine the frequency of CMMC Certified Instructor (CCI) certification. Another requested clarification on the length of time that a CCI may not provide consulting services. One comment recommended changing the rule to require CCIs to provide updates to the CAICO and the CMMC AB no less than annually, in lieu of ·most up to date·. Two comments expressed concern that CCIs are not allowed to provide consulting services to OSCs; one of the comments asserted this would result in reduced quality of training for CMMC Certified Professionals (CCP) and CMMC Certified Assessors (CCA). One comment expressed disagreement with the requirement prohibiting CCIs from exam development and exam proctoring. Another comment recommended a rule update indicating CCIs can teach both CCA and CMMC Certified Professional (CCP) candidates. Response: The DoD declined a commenter's request to modify the rule to allow the CAICO to determine the requirement for validity period of a CCI certification. The DoD considers the 3-year certification period for CCIs as a key CMMC program requirement that is to be enforced by the CAICO. The DoD modified § 170.12(b)(4) to read ·annually· instead of ·most up to date· to clarify the reporting requirement. All CMMC ecosystem members are required to abide by the appropriate ethics and conflicts of interest (COI) policies established by the CMMC AB and CAICO. Rule content pertaining to ethics, quality assurance functions, record keeping, data encryption, security, and other functions across the ecosystem are tailored to reflect the role each entity fills in the ecosystem. The DoD defined COI requirements to reduce the possibility that a CMMC Ecosystem member acting in one capacity may bias, or be biased by, clients that are paying them to perform another CMMC related service. CCIs are not permitted to develop or proctor exams to avoid participating in any activity, practice, or transaction that could result in an actual or perceived conflict of interest.

3. Relationship to CAICO and Other Ecosystem Members Comment:

A written request for DoD records that reasonably describes the record(s) sought. The request should also indicate a willingness to pay processing fees even if it contains a request for a fee waiver. Written requests may be received by postal service or other commercial delivery means, by facsimile, or electronically. All requests must have a postal mailing address included, even if they are received by facsimile or electronically. FOIA requester. Any person, including a partnership, corporation, association, State or State agency, foreign government, foreign national, or a lawyer or other representative acting on behalf of any person, who submits a FOIA request. This definition specifically excludes agencies within the Executive Branch of the Federal Government. FOIA requester service center . Defined in E.O. 13392 . IDA. An official who has been granted authority by the Head of the DoD Component to withhold information requested under the FOIA for one or more of the 9 categories of records exempt from mandatory disclosure. An IDA may also deny a fee category claim by a requester, deny a request for expedited processing, deny a request for a waiver or reduction of fees, review a fee estimate, and confirm that no records were located in response to a request. Perfected FOIA request. A FOIA request that meets the conditions identified in definition ·FOIA request· and arrives at the FOIA office of the DoD Component in possession of the records. Also referred to as a ·correct· request. Privacy Act system of records. Defined in DoD 5400.11-R [1] . Public interest. The interest in obtaining official information that sheds light on an agency's performance of its statutory duties because the information falls within the statutory purpose of the FOIA to inform citizens about their Government's activities. Search. Includes all time spent looking, both manually and electronically, for records that are responsive to a FOIA request. The term ·search· also includes a page-by-page or line-by-line identification (if necessary) of material in the record to determine if it, or portions of it, are responsive to the request. Time spent reviewing documents to determine whether to apply one or more of the statutory exemptions is not search time; it is review time. (1) Duplication. The process of making a copy of a document in response to a FOIA request. Such copies can take the form of paper, microfiche, or audiovisual or machine-readable documentation (e.g., magnetic tape or disc), among others. (2) Review. The examination of documents located in response to a FOIA request to determine whether one (printed page 71849) or more of the statutory exemptions permit withholding. Review also includes processing the documents for disclosure, such as excising them for release. Review does not include the time spent resolving general, legal or policy issues regarding the application of exemptions.

Submitter.

CIS Safeguard 16.12 · Implement Code-Level Security Checks Apply static and dynamic analysis tools within the application life cycle to verify that secure coding practices are being followed.

Implementation Groups: 3 Asset Type: applications Security Function: protect Parent Control: Application Software Security

(C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (D) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6) , if the disclosure would compromise the objectivity or fairness of the test or examination process. (E) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7) , but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (F) Portions of this system of records are exempt from the following subsections of the Privacy Act: (d), (e)(1), and (f)(2), (3), and (4). (ii) Authority. 5 U.S.C. 552a(k)(1) , (k)(2), (k)(5), (k)(6), and (k)(7). (iii) Reasons. (A) Subsection (d) because granting individuals access to information relating to the preparation and conduct of litigation would impair the development and implementation of legal strategy. Accordingly, such records are exempt under the attorney-client privilege. Disclosure might also compromise on-going investigations and reveal confidential informants. Additionally, granting access to the record subject would seriously impair the Navy's ability to negotiate settlements or pursue other civil remedies. Amendment is inappropriate because the litigation files contain official records including transcripts, court orders, investigatory materials, evidentiary materials such as exhibits, decisional memorandum and other case-related papers. Administrative due process could not be achieved by the ·ex parte· correction of such materials. (B) Subsection (e)(1) because it is not possible in all instances to determine relevancy or necessity of specific information in the early stages of case development. What appeared relevant and necessary when collected, ultimately may be deemed unnecessary upon assessment in the context of devising legal strategy. Information collected during civil litigation investigations which is not used during subject case is often retained to provide leads in other cases or to establish patterns of activity. (C) Subsections (f)(2), (3), and (4) because this record system is exempt from the individual access provisions of subsection (d). (18) System identifier and name. N01000-5, Naval Clemency and Parole Board Files. (i) Exemption. (A) Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principal function any activity pertaining to the enforcement of criminal laws.

CIS Safeguard 8.9 · Centralize Audit Logs Centralize, to the extent possible, audit log collection and retention across enterprise assets. Implementation Groups: 2,3 Asset Type: network Security Function: detect Parent Control: Audit Log Management

Administrative staff manuals and instructions, or portions thereof, that establish DoD policy or interpretations of policy that affect the public. This provision does not apply to instructions for employees on tactics and techniques to be used in performing their duties, or to instructions relating only to the internal management of the DoD Component. Examples of manuals and instructions not normally made available are: (1) Those issued for audit, investigation, and inspection purposes, or those that prescribe operational tactics, standards of performance, or criteria for defense, prosecution, or settlement of cases. (printed page 71853) (2) Operations and maintenance manuals and technical information concerning munitions, equipment, systems, and intelligence activities. (d) ·(a)(2)(D)· records. Records released to the public pursuant to 5 U.S.C. 552(a)(3) because of the nature of the subject matter, have become or are likely to become the subject of subsequent requests for substantially the same records. Two additional requests satisfy the criterion of subsequent requests. These records are referred to as ·FOIA-processed (a)(2) records.· (1) The DoD Components shall decide on a case by case basis whether records fall into this category, based on the following factors: (i) The previous experience of the DoD Component with similar records. (ii) The particular circumstances of the records involved, including their nature and the type of information they contain. (iii) The identity and number of requesters and whether there is widespread press, historic, or commercial interest in the records.

(2) This provision of § 286.8 is intended for situations where public access in a timely manner is important. It is not intended to apply where there may be a limited number of requests over a short period of time from a few requesters. The DoD Components may remove the (a)(2)(D) records from their Web site when the appropriate officials determine that access is no longer necessary according to the factors of § 286.8(d)(1). (3) Should a requester submit a FOIA request for FOIA-processed (a)(2) records and insist that it be processed, the DoD Components shall process the request. However, the DoD Components have no obligation to process a FOIA request for 552(a)(2)(A), (B), and (C) records because these records are required to be made available to the public. § 286.9 Indexes. (a) (a)(2) records. (1) Each DoD Component shall maintain in each FOIA reading room an index of records described in § 286.7 that are issued, adopted, or promulgated, after July 4, 1967.

A determination has been made under the authority of the Secretary of Defense that urgent and compelling reasons exist to promulgate this interim rule without prior opportunity for public comment. This action is necessary because of the urgent need to protect the National Security Systems (NSS) and the integrity of the supply chain to NSS. It is necessary to reduce supply chain risk in the acquisition of sensitive information technology systems that are used for intelligence or cryptologic activities; used for command and control of military forces; or from an integral part of a weapon system by avoiding sabotage, maliciously introducing unwanted functions, or other subversion of the design, integrity, manufacturing, production, installation, operation or maintenance of systems. Such acquisition decisions are made daily and, like other cybersecurity measures, the costs to mitigate supply chain risk after a system is already in operation can be very high. In addition, as this is a pilot authority set to expire on September 30, 2018, and the Congress has requested a report on the effectiveness of the authority not later than January 1, 2017, therefore DoD must make this tool available immediately to begin the pilot program and gather feedback for the report to Congress. The globalization of information technology has increased the vulnerability of DoD to attacks on its systems and networks. Failure to implement this rule may cause harm to the Government and to individuals relying on the integrity of NSS, for example, the risk of allowing the malicious insertion of software code or an unwanted function designed to degrade DOD's sensitive systems. DoD has proceeded cautiously to ensure that this rule very closely mirrors the authorities provided in the statute and has little leeway to vary from those terms. However, pursuant to 41 U.S.C. 1707 and FAR 1.501-3(b), DoD will consider public comments received in response to this interim rule in the formation of the final rule. List of Subjects in 48 CFR Parts 208, 212, 215, 233, 239, 244, and 252 Government procurement Manuel Quinones, Editor, Defense Acquisition Regulations System. Therefore, 48 CFR parts 208, 212, 215, 233, 239, 244, and 252 are amended as follows: 1. The authority citation for 48 CFR parts 208, 212, 215, 233, 239, 244, and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR Chapter 1. PART 208-REQUIRED SOURCES OF SUPPLIES AND SERVICES 2. Add section 208.405 to read as follows: 208.405 Ordering procedures for Federal Supply Schedules. In all orders and blanket purchase agreements involving the development or delivery of any information technology, whether acquired as a service or as a supply, consider the need for an evaluation factor regarding supply chain risk (see subpart 239.73). 3. Amend section 208.7402 by: a. Designating the text as paragraph (1); and b. Adding new paragraph (2) to read as follows: 208.7402 General. (1) * * *

The regulations in this subpart do not require duplication of existing records if those records contain all of the information required by this subpart. If a covered person keeps records of all of the information as required by this subpart to comply with other Federal, State, or local regulations, or for any other reason, then those records may be used to meet these requirements. Moreover, persons do not have to keep all of the information required by this rule in one set of records. If they have records containing some of the required information, they may keep those existing records and keep, either separately or in a combined form, any new information required by this rule. There is no obligation to create an entirely new record or compilation of records containing both existing and new information, even if the records containing some of the required information were not created at the time the food was received or released. Requirements for Nontransporters to Establish and Maintain Records to Identify the Nontransporter and Transporter Immediate Previous Sources of Food § 1.1337 What information must nontransporters establish and maintain to identify the nontransporter and transporter immediate previous sources of food? (a) If you are a nontransporter, you must establish and maintain the following records for all food you receive: (1) The name of the firm, address, telephone number and, if available, the fax number and e-mail address of the nontransporter immediate previous source, whether domestic or foreign; (2) An

adequate description of the type of food received, to include brand name and specific variety (e.g., brand x cheddar cheese, not just cheese; or romaine lettuce, not just lettuce); (3) The date you received the food; (4) For persons who manufacture, process, or pack food, the lot or code number or other identifier of the food (to the extent this information exists); (5) The quantity and how the food is packaged (e.g., 6 count bunches, 25 pound (lb) carton, 12 ounce (oz) bottle, 100 gallon (gal) tank); and (6) The name of the firm, address, telephone number, and, if available, the fax number and e-mail address of the transporter immediate previous source (the transporter who transported the food to you). Requirements for Nontransporters to Establish and Maintain Records to Identify the Nontransporter and Transporter Immediate Subsequent Recipients of Food §1.345 What information must nontransporters establish and maintain to identify the nontransporter and transporter immediate subsequent recipients of food? (a) If you are a nontransporter, you must establish and maintain the following records for food you release: (1) The name of the firm, address, telephone number, and, if available, the fax number and e-mail address of the nontransporter immediate subsequent recipient, whether domestic or foreign;

IST received 57 submissions, 56 of which were accepted for the first round of evaluation. After four months of evaluation, 32 of the first-round candidates proceeded to the second round of evaluation. Zero Trust is the term for a set of cybersecurity paradigms to move network defenses from static, physical, network-based perimeters to software-defined security mechanisms based on users, assets, and resources. A zero trust architecture (ZTA) uses zero trust principles to plan enterprise infrastructure and workflows.

To assist the Government: (1) in carrying out a program of inspection to safeguard against threats and hazards to the security and privacy of Government data, or (2) for the purpose of audits, investigations, inspections or similar activities, paragraph (c) of the clause 52.239-YY would require contractors to provide the Government's authorized representatives, which includes CISA (for civilian agencies) as well as other Federal agencies as specified by the contracting officer, with timely and full access to Government data and Government-related data, timely access to contractor personnel involved in performance of the contract, and specifically for the purpose of audit, investigation, inspection, or other similar activity, physical access to any contractor facility with Government data including any associated metadata. If the contractor receives a request for access from CISA, the contractor must confirm the validity of the request by contacting CISA and notifying the contracting officer in writing of the request for access. Assessments. When a FIS is designated as a moderate or high FIPS Publication 199 impact level, paragraph (d) of the clause 52.239-YY would require contractors: (1) to conduct, at least annually, a cyber threat hunting and vulnerability assessment to search for vulnerabilities, risks, and indicators of compromise; and (2) to perform to an annual, independent assessment of the security of each FIS. Upon completion, contractors would submit the results of an assessment, including any recommended improvements or risk mitigations, to the contracting officer. The agency will review the results of the assessment. The agency may require the contractor to implement the recommended improvement or mitigation. The agency may provide the contractor with a rationale for not requiring the contractor to implement the recommendation or mitigation, and if so, the contractor would document the agency's rationale in the System Security Plan (SSP). If the contractor contracts with a third-party assessment organization to perform these assessments, contractors must enter into a confidentiality agreement with the organization to protect Federal data under the contract. To assist with mitigating any potential conflicts of interest, the clause would also require contractors to notify the contracting officer of any existing business relationships the contractor may have with the organization. Specification of Additional Security and Privacy Controls.

Many commenters had questions about existing CMMC conflict of interest (Col) requirements and had suggestions for further protecting the impartiality of the CMMC Program. One commenter requested the Department develop a mechanism to prevent third-party assessment organizations from delaying re-evaluation of NOT MET requirements to create a pipeline of future assessment work. The commenter recommended removing the 10-day re-evaluation deadline requirement currently in the CMMC Rule to prevent any conflicts of interest. Another commenter stated that allowing a (printed page 83125) commercial entity to manage the CMMC 'ecosystem' creates a scenario 'fox watching the henhouse' condition and that fraud and abuse will be rampant. Some commenters questioned the legality of the current CMMC AB's establishment and alleged unethical behavior by its Board of Directors. They cited the number of resignations among its Board of Directors as evidence of internal politics, conflicts of interests, or ethics concerns. One commenter suggested the 6-month 'cooling off period' between

an employee leaving the CMMC AB and supporting other CMMC roles be extended to one year to ensure impartiality within the CMMC Program. Another commenter claimed an informational newsletter offered by the CMMC AB to ecosystem members violates the conflicts of interest requirements. In addition, commenters alleged that the CMMC AB's progress (prior to final rule publication) toward ISO/IEC compliance violates the terms of its contract with DoD, which the DoD should terminate. Commenters also stated that DoD's no-cost contract with the current CMMC AB has forced them to focus on generating revenue instead of building a CMMC Assessor cadre. One commenter cited publicly available tax filings of the current CMMC AB to substantiate that view. Another commenter noted concerns that the rule permits a timeline for meeting the ISO/IEC requirements, rather than requiring immediate compliance, and suggested that it would be more advantageous to cite different ISO/IEC requirements (for conformity assessment) than those identified in the rule. One commenter wrote that significant delays in CMMC implementation this far beyond the Department's earlier objectives of 2020 constitute fraud and claimed that DoD representatives directed companies to comply with requirements that have become irrelevant due to changes in program requirements that occurred during rulemaking. Many commenters stated the Department needs to further clarify existing CoI requirements for CCIs, CCAs, and CCPs in the CMMC Rule text. Specifically, commenters suggested the DoD:

(1) Except as otherwise authorized by subpart E of this part, disclosure of information from a system of records to any person or entity outside the Department of Defense (see § 310.21(b)) may only be made pursuant to a routine use that has been established for the specific system of records. Such uses are the so-called "external routine uses." (2) Each routine use shall include to whom the information is being disclosed and what use and purpose the information will be used. Routine uses shall be written as follows: (i) "To * * *. [person or entity outside of DoD that will receive the information] to * * *. [what will be done with the information] for the purpose(s) of * * * [what objective is sought to be achieved]." (ii) To the extent practicable, general statements, such as "to other Federal agencies as required" or "to any other appropriate Federal agency" shall be avoided. (3) Blanket routine uses (Appendix C to this part) have been adopted that apply to all Component system notices. The blanket routine uses appear at the beginning of each Component's compilation of its system notices. (i) Each system notice shall contain a statement whether or not the blanket routine uses apply to the system. (ii) Each notice may state that none of the blanket routine uses apply or that one or more do not apply. (j) Policies and Practices For Storing, Retiring, Accessing, Retaining, and Disposing of Records. This caption is subdivided into four parts: (1) Storage. Indicate the medium in which the records are maintained. (For (printed page 18778) example, a system may be "automated, maintained on compact disks, diskettes," "manual, maintained in paper files," or "hybrid, maintained in a combination of paper and automated form.") Storage does not refer to the container or facility in which the records are kept. (2) Retrieval. Specify how the records are retrieved (for example, name, SSN, or some other unique personal identifier assigned the individual). (3) Safeguards. Identify the system safeguards (such as storage in safes, vaults, locked cabinets or rooms, use of guards, visitor registers, personnel screening, or password protected IT systems). Also identify personnel who have access to the systems. Do not describe safeguards in such detail as to compromise system security. (4) Retention and Disposal. Indicate how long the record is retained. When appropriate, also state the length of time the records are maintained by the Component, when they are transferred to a FRC, time of retention at the Records Center and when they are transferred to the National Archivist or are destroyed. A reference to a Component regulation without further detailed information is insufficient. If records are eventually destroyed as opposed to being retired, identify the method of destruction (e.g., shredding, burning, pulping, etc). (k) System manager or managers and address. (1) List the title and address of the official responsible for the management of the system.

3.6.2 SHA-512/256 For SHA-512/256, the initial hash value, H (0) , shall consist of the following eight 64-bit words, in hex: `` (0) 0 H = 22312194FC2BF72C (0) 1 H = 9F555FA3C84C64C2 (0) 2 H = 2393B86B6F53B151 (0) 3 H = 963877195940EABD (0) 4 H = 96283EE2A88EFFE3 (0) 5 H = BE5E1E2553863992 (0) 6 H = 2B0199FC2C85B8AA (0) 7 H = 0EB72DDC81C52CA2 `` These words were obtained by executing the SHA-512/t IV Generation Function with t = 256. 3.6.2; and 2.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive

use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations. - The application is made up of a set of loosely coupled components called microservices. Each of the microservices can be hosted on different physical or virtual machines (VMs) and even be geographically distributed (e.g., within several facilities that belong to the enterprise, such as the headquarters, branch offices, and in various cloud service provider environments). - Any transaction involving the application may also involve one or more inter-service (microservice) calls across the network. - A widespread feature (though not necessarily a requirement for cloud-native applications) is the presence of a software platform called the service mesh that provides an integrated set of all application services (e.g., services discovery, networking connections, communication resilience, and security services like authentication and authorization). - Zero trust is the term for an evolving set of cybersecurity paradigms that move defenses from static, network-based perimeters to focus on users and resources. It is a set of security primitives rather than a particular set of technologies.

Establish written policies and procedures for identifying, prioritizing, acquiring, installing, evaluating, and verifying the timely installation of patches, updates, and upgrades throughout the covered entity's or business associate's relevant electronic information systems. (B) Maintenance. Review and test written policies and procedures required by paragraph (a)(4)(ii)(A) of this section at least once every 12 months, and modify such policies and procedures as reasonable and appropriate. (C) Application. Patch, update, and upgrade the configurations of relevant electronic information systems in accordance with the written policies and procedures required by paragraph (a)(4)(ii)(A) of this section and based on the results of the covered entity's or business associate's risk analysis required by paragraph (a)(2) of this section, the vulnerability scans required by § 164.312(h)(2)(i), the monitoring of authoritative sources required by § 164.312(h)(2)(ii), and penetration tests required by § 164.312(h)(2)(iii), within a reasonable and appropriate period of time, as follows, except to the extent that an exception at paragraph (a)(4)(ii)(D) of this section applies: (1) Within 15 calendar days of identifying the need to patch, update, or upgrade the configuration of a relevant electronic information system to address a critical risk in accordance with this paragraph (a)(4)(ii)(C), where a patch, update, or upgrade is available; or, where a patch, update, or upgrade is not available, within 15 calendar days of a patch, update, or upgrade becoming available. (2) Within 30 calendar days of identifying the need to patch, update, or upgrade the configuration of a relevant electronic information system to address a high risk in accordance with this paragraph (a)(4)(ii)(C), where a patch, update, or upgrade is available; or, where a patch, update, or upgrade is not available, within 30 calendar days of a patch, update, or upgrade becoming available. (3) As determined by and documented in the covered entity's or business associate's policies and procedures under paragraph (a)(4)(ii)(A) of this section for all other patches, updates, and upgrades to the configuration of a relevant electronic information system. (D) Exceptions. This paragraph (a)(4)(ii)(D) applies only to the extent that a covered entity or business associate documents that an exception in this paragraph (a)(4)(ii)(D) applies and that all other applicable conditions are met. (1) A patch, update, or upgrade to the configuration of a relevant electronic information system is not available to address a risk identified in the risk analysis under paragraph (a)(2) of this section. (2) The only available patch, update, or upgrade would adversely affect the confidentiality, integrity, or availability of electronic protected health information. (E) Alternative measures.

Section 170.17 addresses how an OSC will achieve and maintain compliance with CMMC Level 2 Certification Assessment. The OSC must successfully implement the security requirements listed in § 170.14(c)(3) within its Level 2 CMMC Assessment Scope as described in § 170.19(c). Successful implementation requires meeting all objectives defined in NIST SP 800-171A for the corresponding CMMC Level 2 security requirements. After implementation, the OSC must hire a C3PAO to perform an assessment to verify the implementation. The C3PAO will score the OSC using the scoring methodology provided in § 170.24. All objectives must be met in order for a security requirement to be considered fully implemented; in some cases, if not all objectives are met, some security requirements may be placed on a POA&M as defined in § 170.21. If the minimum score has been achieved and some security requirements are in a POA&M, the OSC has a Conditional Certification Assessment; if the minimum score has been achieved and no security requirements are in a POA&M, the OSC has a

Final Certification Assessment. For Conditional Certification Assessments, a POA&M close-out must be conducted within 180 days as described in § 170.21(b). After both Conditional Certification Assessment and Final Certification Assessment, the C3PAO will input the OSC's results into the CMMC instantiation of eMASS as described in § 170.17(a)(1)(i). After both Conditional Certification Assessment and Final Certification Assessment, the OSC must submit an affirmation as described in § 170.22. In order to be eligible for a contract with a CMMC Level 2 Certification Assessment requirement, the OSC must have a CMMC Level 2 Conditional Certification Assessment or CMMC Level 2 Final Certification Assessment and have submitted an affirmation. The CMMC Level 2 Certification Assessment must be completed tri-annually and the affirmation must be completed annually. Section 170.18: CMMC Level 3 Certification Assessment and Affirmation Requirements Section 170.18 addresses how an OSC will achieve and maintain compliance with CMMC Level 3 Certification Assessment. The OSC must have a CMMC Level 2 Final Certification Assessment based on its Level 3 CMMC Assessment Scope. The OSC must successfully implement the security requirements listed in § 170.14(c)(4) and table 1 to § 170.14(c)(4) within its Level 3 CMMC Assessment Scope as described in § 170.19(d). Successful implementation requires meeting all objectives defined in NIST SP 800-172A for the corresponding CMMC Level 3 security requirements. After implementation, the OSC must contact DCMA DIBCAC to perform an assessment to verify the (printed page 89066)

The DoD Components shall interpret FOIA requests liberally when determining which records are responsive, and may release non-responsive information. Responsive documents may contain large amounts of non-responsive information, the review of which may cause delays in responding to the requester. In these cases, the DoD Components should identify the information which is non-responsive, redact it, and annotate it as non-responsive. The Components shall not apply these procedures to documents that have a relatively small percentage of non-responsive information. Additionally, redactions of non-responsive information shall not be made in sections smaller than the paragraph level. That is, a non-responsive sentence within an otherwise responsive paragraph shall not be redacted as non-responsive. (p) Honoring form or format requests. The DoD Components shall provide the record in any form or format requested if the record is readily reproducible in that form or format in the Component's automated system. Every effort will be made to ensure the copy provided is in a reasonably usable form. The DoD Components shall make reasonable efforts to use available office equipment to digitally reproduce hard copy records onto digital media. If a Component must outsource to reproduce a record into the requested format, the readily-reproducible criterion is not met. In responding to requests for records, the DoD Components shall make reasonable efforts to search for records in electronic form or format if maintained in automated systems, except when such efforts would significantly interfere with the operation of the automated systems. Such determinations shall be made on a case by case basis. (q) Annual report. The Annual FOIA Report is mandated by 5 U.S.C. 552(e)(1) and completed on a fiscal year basis. Additionally, E.O. 13392 requires additional reporting in the annual report through fiscal year 2007. Due to the magnitude of the requested statistics and the need to ensure accuracy, the DoD Components shall track this data as requests are processed. This will also facilitate quick compilation of the statistics in completing the report. (1) Each September, DFOIPO shall post on its Web site instructions to the Components concerning Component input for the annual report. The DoD Components shall forward their report to DFOIPO no later than November 30. In turn, the DA&M shall produce a consolidated report for submission to the Attorney General, and will place a copy of this report on the Internet for public access. The DoD Components shall use the current edition of DD Form 2564, 'Annual Report: Freedom of Information Act.' (2) This reporting requirement is assigned Report Control Symbol DD-DA&M(A)1365, Freedom of Information Act Report to Congress. Subpart B-FOIA Reading Rooms § 286.7 Requirements. (a) Reading room. The FOIA requires records described in 5 U.S.C. 552(a)(2)(A)

The Federal Information Processing Standards Publication Series of the National Institute of Standards and Technology (NIST) is the official series of publications relating to standards and guidelines adopted and promulgated under the provisions of Section 5131 of the Information Technology Management Reform Act of 1996 (Public Law 104-106) and the Federal Information Security Management Act of 2002 (Public Law 107-347). These mandates have given the Secretary of Commerce and NIST important responsibilities for improving the utilization and management of computer and related telecommunications systems in the federal government. The NIST, through its Information Technology Laboratory, provides leadership, technical guidance, and coordination of government efforts in the development of standards and guidelines in these areas. NATIONAL SECURITY SYSTEM: Any information system (including any telecommunications system) used or operated by an agency or by a contractor of

an agency, or other organization on behalf of an agency- (i) the function, operation, or use of which involves intelligence activities; involves cryptologic activities related to national security; involves command and control of military forces; involves equipment that is an integral part of a weapon or weapons system; or is critical to the direct fulfillment of military or intelligence missions (excluding a system that is to be used for routine administrative and business applications, for example, payroll, finance, logistics, and personnel management applications); or, (ii) is protected at all times by procedures established for information that have been specifically authorized under criteria established by an Executive Order or an Act of Congress to be kept classified in the interest of national defense or foreign policy. [44 U.S.C., SEC. 3542]

- Implements A Secure Software Development Process - Practices Secure Design and Vulnerability Remediation - Practices Responsible Vulnerability Reporting Disclosure - Uses Multifactor Authentication (if applicable) - Free from Hard Coded Secrets - Uses Strong Cryptography (if applicable) - User Data is Identified and Secured ## 2.2.2.2 Practices Secure Design and Vulnerability Remediation Practices Secure Design and Vulnerability Remediation

The Paperwork Reduction Act (44 U.S.C. chapter 35) applies; however, the proposed changes to the FAR do not impose additional information collection requirements to the paperwork burden previously approved under the Office of Management and Budget (OMB) Control Number 0704-0567, entitled 'Department of Defense Contract Security Classification Specification'. The proposed rule also touches but does not impact information collection requirements concerning the CAGE code. OMB Control Number 9000-0185, Commercial and Government Entity Code was established by OMB under FAR case 2012-024, but requires final clearance under this case. This clearance covers the following: Offerors that do not already have a CAGE code to obtain and provide a CAGE code referred to as North Atlantic Treaty Organization (NATO) CAGE (NCAGE) code for foreign entities; offerors to represent whether they are owned or controlled by another entity, and if so, to provide the CAGE code and name of such entity; and contractors to communicate any change to the CAGE code to the contracting officer within 30 days after the change. As a part of this case, the Regulatory Secretariat has submitted a request for approval of this information collection requirement to OMB. (printed page 33203) A. Public reporting burden for the collection of information under OMB Control number 9000-0185 includes the time for reviewing instructions, searching existing data sources, gathering and maintaining the data needed, and completing and reviewing the collection of information. The annual reporting burden is estimated as follows: Respondents: 735. Total annual responses: 11,358. Total burden hours: 5,616.75. B. Request for Comments Regarding Paperwork Burden. DoD, GSA and NASA are soliciting comments from the public in order to: Evaluate whether this collection of information is necessary for the proper performance of the functions of the FAR, including whether the information will have practical utility; Evaluate the accuracy of the estimate of the burden, including the validity of the methodology and assumptions used; Enhance the quality, utility, and clarity of the information to be collected; and Minimize the burden of the collection of information on those who are to respond, including through the use of appropriate collection techniques or other forms of information technology. Organizations and individuals desiring to submit comments on the information collection requirements should submit comments no later than September 10, 2019 to: FAR Desk Officer, OMB, Room 10102, NEOB, Washington, DC 20503, and a copy GSA. The copy to GSA can be submitted by either of the following methods: Federal eRulemaking Portal: This website provides the ability to type short comments directly into the comment field or attach a file for lengthier comments. Go to <http://www.regulations.gov> and follow the instructions on the site. Mail:

In recognition of the pervasive cyber threat both to DoD and to the DIB, CMMC Program requirements are designed to ensure compliance with existing standards for protection of FCI and CUI. These cybersecurity requirements align directly to NIST guidelines (NIST SP 800-171 R2 and NIST SP 800-172 Feb2021) and the basic safeguarding requirements in FAR clause 52.204-21 that apply to all executive agencies. Since December 2017, DFARS clause 252.204-7012 has required contractors to implement the NIST SP 800-171 security requirements to provide adequate security as applicable for processing, storing, or transmitting CUI on non-Federal information systems, as needed in support of the performance of a DoD contract. The executive branch's CUI Program is codified in 32 CFR part 2002 and establishes policy for designating, handling, and decontrolling information that qualifies as CUI. The definition of CUI and general requirements for its safeguarding are included in 32 CFR 2002.4 and 2002.14 . 32 CFR 2002.14(h)(2) specifically requires that Agencies must use NIST SP 800-171 when establishing security requirements to protect CUI's confidentiality on non-Federal

information systems . . . Contractually, DFARS clause 252.204-7012 requires contractors to implement the NIST SP 800-171 R2 security requirements, and that requirement applies, regardless of the number of computers or components in a non-Federal information system or the size of the contractor or subcontractor, as applicable. DoD's original implementation of security requirements for adequate safeguarding of CUI relied upon self-attestation by contractors. Since that time, the DoD Inspector General and the DCMA found contractors did not consistently implement mandated system security requirements for safeguarding CUI and recommended DoD take steps to assess a contractor's ability to protect this information. The DoD has streamlined requirements to reduce the burden of compliance on contractors. Analysis of costs to meet CMMC requirements is provided in the regulatory impact analysis for this rule. As described in the estimate included with the rule, the major cost categories for compliance with CMMC requirements include costs for completing a self-assessment (e.g.,

We also believe that the current maintenance requirement in 45 CFR 164.306(e) would benefit from increased specificity in light of the dramatic transformation of the health IT environment discussed above. For example, providing the frequency with which regulated entities must review and update their security measures would improve the security of ePHI and regulated entities' compliance with the Security Rule. The Security Rule's maintenance requirement would be further strengthened by requiring regulated entities to test their security measures to verify their sufficiency, and by clarifying the Department's expectations regarding documentation. Regulated entities' lack of documentation about how they implement security measures makes it difficult for them to know what security measures they have in fact implemented and to demonstrate compliance with the requirements of the Security Rule. Finally, the maintenance requirement in 45 CFR 164.306(e) is not included in or designated as a Security Rule standard, although it explicitly references the overarching documentation requirements in 45 CFR 164.316(b)(2)(iii) . Thus, there is overlap between the two sections that may be causing confusion regarding the obligations of regulated entities to maintain security measures.

3. Proposals

a. Section 164.306(a)-General Requirements The Department proposes to expand the introductory language to the general requirements provision at 45 CFR 164.306(a) to clarify the extent to which the general requirements apply to the obligations of regulated entities with respect to ePHI that they create, receive, maintain, or transmit. Under the proposal, the Department would clarify that the general requirements apply to ·all· ePHI. Additionally, the Department proposes to move language from paragraph (a)(1) to paragraph (a) to further emphasize that regulated entities must apply the requirements of the Security Rule to protect all of the ePHI they create, receive, maintain, or transmit. We also propose to clarify that ·each· regulated entity would be required to apply the obligations in paragraphs (a)(1) through (4) to all ePHI it creates, receives, maintains, or transmits. The Department believes that this proposal would stress to regulated entities that each and every covered entity and business associate would be responsible for ensuring it meets Security Rule requirements with respect to all ePHI. The Department believes this proposed change would also help address issues raised by current interpretations of the Security Rule that suggest that its plain wording may not require regulated entities to fully implement each security measure to protect all ePHI. Thus, the Department's proposed language would clarify that a security measure must be implemented such that it protects the security of all ePHI and all information systems that affect the confidentiality, integrity, and availability of ePHI.

establishments) would experience higher costs than the average cost per establishment because each firm would need to apply the proposals to all of their establishments. In the context of the RFA, HHS generally considers an economic impact exceeding 3 percent of annual revenue to be significant, and 5 percent or more of the affected small entities within an identified industry to represent a substantial number. More than 5 percent of the small covered entities listed under the NAICS codes in table 4 are one-establishment firms with fewer than five employees, [1005] so the analysis must determine how the effects of the quantified costs on one-establishment firms compare to their revenues. As explained above, the cost for a one-establishment firm is \$1,235, so only small firms whose revenues are below \$41,167 [= \$1,235/0.03] would experience an effect exceeding 3 percent. Among the NAICS codes for health care providers, the small firms with the lowest revenues are one-establishment HMO [Health Maintenance Organization] Medical Centers (NAICS 621491) with fewer than five employees, which had an estimated average yearly revenue in 2021 of \$108,000. Residential Intellectual and Developmental Disability Facilities (NAICS 623210) had the second lowest revenues for one-establishment firms with fewer than five employees, with \$180,000. Offices of Mental Health Practitioners (NAICS 621330) have the third lowest revenues for one-establishment firms with fewer

than five employees, with \$189,000. Thus, the Department believes that almost all regulated entities have annual revenues that exceed these amounts. The Department acknowledges that there may be very small firms—namely firms without employees—whose revenues are below \$41,167. We believe that such firms would comply with the regulation by purchasing services from software and web-hosting companies whose costs may increase as a result of the proposed changes. Such software and web-hosting companies would be business associates, and thus costs to them are already accounted for. We believe that, to the extent that these business associates decide to recover their minor cost increases by raising the prices of the services sold to non-employer firms, these incremental costs passed through to their small-firm customers would be negligible because they will be spread among many non-employer firms. The Department has separately analyzed the effects of the NPRM on health plan sponsors and does not view the projected costs as a significant burden because the proposed changes would result in annualized costs per plan sponsor of approximately \$6,133 [= \$4,552,995,816/742,411 health plan sponsors]. The quantified impact of \$6,133 per health plan sponsor would only apply to those sponsors whose annual revenue is \$204,433 or less. [1006] The Department believes there are few, if any, group health plan sponsors with annual revenues below this amount because the average revenue of a U.S. business with 1-4 employees is \$387,000 [

(Comment 75) A comment states that FDA's procedures for the exercise of its records access authority should embody recognition of the special status of confidential ingredients, as follows: First, FDA should provide that it will not routinely seek access to records that would require the disclosure of confidential ingredient information; second, if FDA concludes that it needs access to information about ingredients, it should present a written explanation to the custodian of the records that sets forth the basis for the agency's conclusion; and third, FDA should seek records access in an orderly manner, beginning with ingredients other than flavors and spices. The comment states that it will not be possible for FDA to assess simultaneously each ingredient in a product as the potential source of the problem that is being investigated. Given that flavor and spice information is highly confidential and that the low levels of use of those ingredients make it unlikely that one of them will be the source of the problem investigated, it is reasonable to provide that requesting information on flavors and spices will occur only as a last resort. Finally, FDA should provide for special procedures to ensure that, when flavor and spice information is obtained, it is properly protected from disclosure, whether advertently or otherwise. The comment urges FDA to implement a system to adequately safeguard against the inadvertent release of proprietary and confidential information. Among other things, such information should be shared within FDA only to the limited extent necessary to conduct the particular investigation that resulted in the disclosure. The comment asserts that highly proprietary information about product formulas should not be widely distributed within the agency, and all persons who are made privy to the information should be reminded explicitly of the confidential nature of the information. Moreover, the comment states that FDA should amend its public information regulations to provide expressly that information obtained under the records access authority is exempt from disclosure under one or more of the exemptions under the Freedom of Information Act (FOIA) (5 U.S.C. 552). (Response) FDA's procedure for accessing records is outside the scope of this final rule. FDA will consider these comments when it develops guidance for its investigations outlining how FDA intends to implement its access authority in section 414(a) of the FD&C Act. Such guidance will be subject to public comment under FDA's good guidance practice regulations (CGPs) § 10.115 (21 CFR 10.115). 14. Restaurant

(Comment 160) One comment states that the rules on recordkeeping are not enforceable outside the United States. The comment states that any legal proceedings based on failure to comply with the final rule that could result in confiscation of assets held in the United States or action against foreign executives visiting U.S. territory would be considered by a foreign country to be a very grave step. This would be unworkable in practice and problematic in terms of bilateral relations. The comment requests that FDA clarify that no enforcement action will be taken against foreign persons outside the United States. (Response) Foreign persons, except those who transport food in the United States, are not subject to subpart J of this final rule and thus, for the most part, the concerns raised by the comment are moot. If FDA needs to access records kept by foreign persons, FDA intends to work in cooperation with the relevant competent authorities to do so. (Comment 161) One comment encourages FDA not to use incidental infractions of its final recordkeeping regulations as a pretext for bringing additional enforcement actions for alleged violations of other agency regulations that are outside the scope of the Bioterrorism Act. (Response) Nothing in the proposed or final rule suggests that FDA would take such actions. O. Comments on What Are the Compliance Dates for This Subpart? (Proposed § 1.368) (Comment 162) Many comments strongly urge FDA to revise

the compliance dates in the proposed rule. The comments state that given the scope of the proposed requirements it is not possible for industry to be in compliance within the 6, 12, or 18 months proposed by FDA. The comments state that each of the new requirements imposes programming, training, and business practice adjustments that FDA must take this into account in setting an appropriate effective date for the regulation. The recommendations that FDA received from comments are as follows: 9 to 12 months for larger businesses; 1 year regardless of the size of the business; 18 months regardless of the size of the business; 18 months for large firms and 24 to 30 months for smaller firms, depending on their numbers of employees; an additional 1 year for each entity group; and 2 to 7 additional years.

From the NIST SP 800-172 Rev 3 Final Public Draft: Sign appropriate access agreements prior to being granted access; and NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 2. Re-sign access agreements to maintain access to systems when access 1390 agreements have been updated or [Assignment: organization-defined frequency]. D
DISCUSSION Access agreements include nondisclosure agreements, acceptable use agreements, rules of behavior, and conflict-of-interest agreements. Signed access agreements include an acknowledgement that individuals have read, understand, and agree to abide by the constraints associated with systems processing, storing, or transmitting CUI to which they have authorized access. This requirement is sourced to a control tailored out of the SP 800-53B [13]

The CSA may approve contractors to transmit SECRET or CONFIDENTIAL information within the United States and its territorial areas by means of a commercial delivery entity that is a current holder of the GSA contract for overnight delivery, and which provides nation-wide, overnight service with computer tracking and reporting features (a list of current contract holders may be found at: <https://www.archives.gov/isoo/faqs#what-is-overnightcarriers>). Such entities do not need to be determined eligible for access to classified information. (i) Prior to CSA approval, the contractor must establish and document procedures to ensure the proper protection of incoming and outgoing classified packages, including the street delivery address, for each cleared facility intending to use GSA-listed commercial delivery entities for overnight services. (ii) Contractors will establish procedures for the use of commercial delivery entities in accordance with 32 CFR part 2001 . The procedures will: (A) Confirm that the commercial delivery entity provides nationwide, overnight delivery service with automated in-transit tracking of the classified packages. (B) Ensure the package integrity during transit and that incoming shipments are received by appropriately cleared personnel. (C) Not be used for COMSEC, NATO, or FGI. (4) Couriers and hand carriers. Contractors may designate cleared employees as couriers or hand carriers. Contractors will: (i) Brief employees providing such services on their responsibility to safeguard classified information and keep classified material in their possession at all times. (ii) Provide employees with an identification card or badge which contains the contractor's name and the name and a photograph of the employee. (iii) Make arrangements in advance of departure for overnight storage at a USG installation or at a cleared contractor's facility that has appropriate storage capability, if needed. (iv) Conduct an inventory of the material prior to departure and upon return. The employee will carry a copy of the inventory with them. (5) Use of commercial passenger aircraft. The contractor may authorize cleared employees to hand carry classified material aboard commercial passenger aircraft. (i) Routine processing. Employees hand carrying classified material are subject to routine processing by airline security agents. Hand-held packages will normally be screened by x-ray examination. If security personnel are not satisfied with the results of the inspection and requests the prospective passenger to open a classified package for visual examination, the traveler must inform the screener that the carry-on items contain USG classified information and cannot be opened. Under no circumstances may traveler or security personnel open the classified material unless required by customs or other government officials. (ii) Special processing.

CIS Safeguard 4.7 · Manage Default Accounts on Enterprise Assets and Software Manage default accounts on enterprise assets and software, such as root, administrator, and other pre-configured vendor accounts. Example implementations can include: disabling default accounts or making them unusable. Implementation Groups: 1,2,3 Asset Type: users Security Function: protect Parent Control: Secure Configuration of Enterprise Assets and Software

to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to

satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because this system of records is compiled for law enforcement purposes and is exempt from the access provisions of subsections (d) and (f). (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NRO will, nevertheless, continue to publish such a notice in broad generic terms as is its current practice. (F) Consistent with the legislative purpose of the Privacy Act of 1974, the NRO will grant access to nonexempt material in the records being maintained. Disclosure will be governed by NRO's Privacy Regulation, but will be limited to the extent that the identity of confidential sources will not be compromised; subjects of an investigation of an actual or potential criminal violation will not be alerted to the investigation; the physical safety of witnesses, informants and law enforcement personnel will not be endangered, the privacy of third parties will not be violated; and that the disclosure would not otherwise impede effective law enforcement. Whenever possible, information of the above nature will be deleted from the requested documents and the balance made available. The controlling principle behind this limited access is to allow disclosures except those indicated above. The decisions to release information from these systems will be made on a case-by-case basis. (2) System identifier and name. QNRO-10, Inspector General Investigative Files. (i) Exemption. This system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principle function any activity pertaining to the enforcement of criminal laws. Any portion of this system which falls within the provisions of 5 U.S.C. 552a(j)(2) may be exempt from the following subsections of 5 U.S.C. 552a (c)(3), (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (H), and (I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons.

(A) From subsection (c)(3) and (d) when access to accounting disclosures and access to or amendment of records would cause the identity of a confidential source to be revealed. Disclosure of the source's identity not only will result in the Department breaching the promise of confidentiality made to the source, but it will impair the Department's future ability to compile investigatory material for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, Federal contracts, or access to classified information. Unless sources can be assured that a promise of confidentiality will be honored, they will be less likely to provide information considered essential to the Department in making the required determinations. (B) From (e)(1) because in the collection of information for investigatory purposes, it is not always possible to determine the relevance and necessity of particular information in the early stages of the investigation. In some cases, it is only after the information is evaluated in light of other information that its relevance and necessity becomes clear. Such information permits more informed decision making by the Department when making required suitability, eligibility, and qualification determinations. (15) System identifier and name. DCIFA 01, CIFA Operational and Analytical Records. (i) Exemption. This system of records is a compilation of information from other Department of Defense and U.S. Government systems of records. To the extent that copies of exempt records from those `other' systems of records are entered into this system, OSD hereby claims the same exemptions for the records from those `other' systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent (A) such provisions have been identified and an exemption claimed for the original record and (B) the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions are claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, and to preserve the confidentiality and integrity of Federal evaluation materials. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (16) System identifier and name.

not safeguarding CUI in accordance with contract requirements), the Contractor may be financially liable for Government costs incurred in the course of the response and mitigation efforts in addition to any other damages at law or remedies available to the Government for noncompliance. (9)(i) The Government will protect contractor bid or proposal information, contractor proprietary business information, and contractor-attributational information related to a CUI incident, against unauthorized use or release to the extent required by law. (ii) The agency may release outside the Government contractor bid or proposal information, contractor proprietary business information, and contractor-attributational information that is not created by or for the Government, but that is related to a CUI incident. (A) To entities with missions that may be affected by such information; (B) To entities that may be called upon to assist in the diagnosis, detection, or mitigation of CUI incidents; or (C) For national security purposes, including cyber situational awareness. (iii) The Government may use and release contractor bid or proposal information, contractor proprietary business information, and contractor-attributational information, created by or for the Government and related to a CUI incident, outside of the Government for purposes and activities associated with responding to a CUI incident and for any other lawful Government purpose or activity. (iv) In any authorized release, the Government will minimize the contractor proprietary business information and contractor-attributational information that it includes. (10) An agency, at its sole discretion, may obtain assistance from Federal agencies or entities outside the Government, such as third-party firms to aid incident response activities. (11) The SF XXX will list in Part C, Section IV incident reporting requirements that differ from or are in addition to those in this clause, such as requirements for CUI in a CUI Specified category. (h) Subcontracts. (1) Except for the acquisitions in paragraph (h)(2), in subcontracts at any tier, or other contractual instruments, for which performance involves CUI identified in the SF XXX, Controlled Unclassified Information (CUI) Requirements, the Contractor shall: (i) Include this clause, including this paragraph (h), without alteration except to identify the parties; (ii) Include the information in the SF XXX, Controlled Unclassified Information (CUI) Requirements, modified as required to address the CUI that applies to the subcontract; and (iii) Require subcontractors to notify the prime Contractor or next higher tier subcontractor within 8 hours of discovery of a suspected or confirmed CUI incident.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204, 212, and 252 [Docket DARS-2017-0016] RIN 0750-AJ55 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to remove a provision that provided guidelines to offerors when proposing an alternative line item structure in response to a solicitation. DATES: Effective May 30, 2018. FOR FURTHER INFORMATION CONTACT: Ms. Carrie Moore, telephone 571-372-6093. SUPPLEMENTARY INFORMATION: I. Background DoD is amending the DFARS to remove DFARS provision 252.204-7011, Alternative Line Item Structure, the associated prescription at DFARS 204.7109(b), and a cross-reference at DFARS 212.301(f)(ii)(C). DFARS provision 252.204-7011 advises offerors that they may propose an alternative to the contract line item structure included in the solicitation. The purpose of this provision is to ensure that the resulting contract structure is economically and administratively advantageous to both the Government and the contractor. This provision is prescribed for use in all solicitations that use Federal Acquisition Regulation (FAR) part 12 procedures for the acquisition of commercial items or for the initial provisioning of spares. However, this DFARS provision is duplicative of the information provided in FAR provision 52.204-22, Alternative Line Item Proposal, which is included in all solicitations. When the DFARS provision was implemented, no standardized guidance on line item structure existed for the Government or contractors. A final rule was published in the Federal Register on January 13, 2017, at 82 FR 4709 to implement a uniform line item structure in the FAR for all Federal Government. That final rule established FAR provision 52.204-22, Alternate Line Item Proposal, which covers the information included in DFARS 252.204-7011. As a result, the DFARS provision is now redundant and can be removed. The removal of this DFARS provision supports a recommendation from the DoD Regulatory Reform Task Force. On February 24, 2017, the President signed Executive Order (E.O.) 13777, 'Enforcing the Regulatory Reform Agenda,' which established a Federal policy 'to alleviate unnecessary regulatory burdens' on the American people. In accordance with E.O. 13777

The concept of Attribute Based Access Control (ABAC) has existed for many years. It represents a point in the space of logical access control that includes access control lists, role-based access control, and the ABAC method for providing access based on the evaluation of attributes. Traditionally, access control has been based on the identity of a user requesting execution of a capability to perform an operation (e.g., read) on an object (e.g., a file), either directly, or through predefined attribute types such as roles or groups assigned to that user. Practitioners have noted that this approach to access control is often cumbersome to manage given the need to associate capabilities directly to users or their roles or groups. It has also been noted that the requester qualifiers of identity, groups, and roles are often insufficient in the expression of real-world access control policies. An alternative is to grant or deny user requests based on arbitrary attributes of the user and arbitrary attributes of the object, and environment conditions that may be globally recognized and more relevant to the policies at hand. This approach is often referred to as ABAC. In November 2009, the Federal Chief Information Officers Council (Federal CIO Council) published the Federal Identity, Credential, and Access Management (FICAM) Roadmap and Implementation Plan v1.0 [FEDCIO1], which provided guidance to federal organizations to evolve their logical access control architectures to include the evaluation of attributes as a way to enable access within and between organizations across the Federal enterprise. In December 2011, the FICAM Roadmap and Implementation Plan v2.0 [FEDCIO2] took the next step of calling out ABAC as a recommended access control model for promoting information sharing between diverse and disparate organizations.

Accordingly, the Department of Defense proposes to amend 32 CFR part 117 as follows: PART 117-NATIONAL INDUSTRIAL SECURITY PROGRAM OPERATING MANUAL (NISPOM) 1. The authority citation for part 117 continues to read as follows: Authority: 32 CFR part 2004 ; E.O. 10865 ; E.O. 12333 ; E.O. 12829 ; E.O. 12866 ; E.O. 12968 ; E.O. 13526 ; E.O. 13563 ; E.O. 13587 ; E.O. 13691 ; Public Law 108-458 ; Title 42 U.S.C. 2011 et seq.; Title 50 U.S.C. Chapter 44; Title 50 U.S.C. 3501 et seq. 2. Amend §117.3 in paragraph (b) by adding in alphabetical order the definitions of ·Authorization to operate· and ·Pedestrian door locks· to read as follows: (printed page 86293) §117.3 Acronyms and definitions. * * * * * (b) *** Authorization to operate means an approval granted by an authorizing official for a system to process classified information. * * * * * Pedestrian door locks means a series of GSA-approved (FF-L-2890C) preassembled locks designed, tested, and approved for security, fire safety, life safety, and accessibility when installed on doors located in the occupants anticipated path of travel to a means of egress to evacuate the facility in a fire emergency. * * * * * 3. Amend §117.5 by revising paragraph (d) to read as follows: §117.5 Information collections. * * * * * (d) DoD collection. ·DoD Security Agreement·, is assigned OMB Control Number: 0704-0194. ·National Industrial Security System·, a CSA information collection, is assigned OMB Control Number: 0704-0571, and is a DoD information collection used to conduct its monitoring and oversight of contractors. Department of Defense ·Contract Security Classification Specification·, (available at: <https://www.esd.whs.mil/Portals/54/Documents/DD/forms/dd/dd0254.pdf> and <https://www.dcsa.mil/is/nccs/>), is assigned OMB Control Number: 0704-0567 and used by both DoD and agencies which have an industrial security agreement with DoD. ·Defense Information System for Security·, is assigned OMB Control Number: 0704-0573. Defense Information System for Security is a DoD automated system for personnel security, providing a common, comprehensive medium to record, document, and identify personnel security actions within DoD including submitting adverse information, verification of security clearance status, requesting investigations, and supporting continuous evaluation activities. It requires personal data collection to facilitate the initiation, investigation and adjudication of information relevant to DoD security clearances and employment suitability determinations for active duty military, civilian employees and contractors seeking such credentials. * * * * * 4. Amend §117.7 by: a. Revising paragraph (b) introductory text; b. In paragraph (f) introductory text, removing the words ·official reviews· and adding in their place the words ·security reviews·; c. In paragraph (f)(2), adding the words ·for review· after the word ·Providing·; and d. Revising paragraphs (h)(1)(i) and (h)(1)(ii)(A). The revisions read as follows: §117.7 Procedures. * * * * * (b) Contractor Security Officials.

Changes to the health care environment and the operations of regulated entities have increased the importance of implementing strong security measures to protect ePHI and the information systems that create, receive, maintain, or transmit it. While we recognize the burdens posed by such implementation on regulated entities, there is also a clearly documented increase in the number of breaches of unsecured PHI and instances of cybercriminals accessing ePHI without authorization at

regulated entities. The changes to the health care environment, including the increase in breaches and cyberattacks, and operations of regulated entities have made it increasingly likely that unauthorized persons will seek to obtain ePHI and disrupt the U.S. health care system. Additionally, the clearly documented failure of regulated entities to fully implement the policies and procedures required by the Security Rule and apply the required security measures throughout their operations has caused the Department to question whether the existing Security Rule should be revised to clarify and strengthen the obligations of regulated entities and revisit our (printed page 917) decision from 2013. [268] In many cases involving a breach of ePHI that OCR has investigated, a breach may not have occurred, or would have been less widespread and disruptive, had the regulated entities fully implemented the provisions of the Security Rule. [269]

2. NCVHS Believes That the Security Standards Evolve To Address Changes in the Health Care Environment The Department is not alone in believing that the Security Rule should be strengthened to address concerns about whether -regulated entities are sufficiently protecting the confidentiality, integrity, and availability of ePHI. An inquiry conducted by NCVHS between July 2021 and September 2023 reached the same conclusion. [270] During this inquiry, NCVHS listened to the testimony of cybersecurity experts and Department officials. The experts and Department officials consistently voiced their concerns about the major increase in incidents and, in particular, the widespread lack of robust risk analysis on the part of covered entities and business associates that would lead to prior planning for, and mitigation of, a range of cybersecurity threats. [271] In response to this inquiry and consistent with their statutory mandate, [272] NCVHS transmitted two letters to the Secretary with recommendations for improving cybersecurity practices in the health care industry, including recommendations for modifying the Security Rule. [273] As part of the explanation for its concerns, NCVHS cited a 2021 survey of acute and ambulatory care organizations that found only 32 percent of those organizations had a comprehensive security program, while only 26 percent of the long-term and post-acute care facilities met the minimum security requirements. [274] Specifically, NCVHS made the following recommendations for improvements to the Security Rule:

(6) The title and business address of the agency official who is responsible for the SOR, (7) The agency procedures whereby an individual can be notified at his request if the SOR contains a record pertaining to him, (8) The agency procedures whereby an individual can be notified at his request how he can gain access to any record pertaining to him contained in the SOR, and how he can contest its contents; and (9) The categories of sources of records in the system. Timeliness.

Sufficiently current to ensure that any determination based on the record will be accurate and fair.

§ 329.4 Policy. In accordance with 32 CFR part 310 , it is NGB's policy that: (a) Personal information contained in any SOR maintained by any NGB organization will be safeguarded to the extent authorized by 5 U.S.C. 552a , Appendix I of Office of Management and Budget Circular No. A-130, and any other applicable legal requirements. (b) NGB will collect, maintain, use, and disseminate personal information only when it is relevant and necessary to achieve a purpose required by a statute or Executive Order. (c) NGB will collect personal information directly from the individuals to whom it pertains to the greatest extent possible and will provide individuals a PAS at the time of collection when the information being collected will be filed and/or retrieved by the subject's name or other unique identifier. The PAS will contain the following elements, as required by 5 U.S.C. 552a : (1) The statutory authority or Executive Order that allows for the solicitation, (2) The intended use/purpose that will be made of the information collected, (3) The routine uses that may be made of the information collected; and (4) Whether it is mandatory or voluntary for the individual to disclose the requested information and the non-punitive effects on the individual for not providing all or any part of the requested information. Collection can only be mandatory if the statutory authority or Executive Order cited provides a penalty for not providing the information. (d) NGB offices maintaining records and information about individuals will ensure that such data is protected from unauthorized access, use, dissemination, disclosure, alteration, and/or destruction. Offices will (printed page 24127) establish safeguards to ensure the security of personal information is protected from threats or hazards that might result in substantial harm, embarrassment, inconvenience, or unfairness to the individual using guidelines found in 32 CFR part 310, subpart B , 32 CFR part 310, Appendix A, and DoD Manual (DoDM) 5200.01, Volume 4, entitled "DoD Information Security Program: Controlled Unclassified Information (CUI)" (Available at http://www.dtic.mil/whs/directives/corres/pdf/520001_vol4.pdf). (e) NGB offices shall permit individuals to access and have a copy of all or any portion of records about them, unless an exemption for the system has been properly established (see 5 U.S.C. 552a , 32 CFR part 310, subparts D and F , and section 7 of

SUPPLEMENTARY INFORMATION: I. Background DoD, GSA, and NASA are proposing to revise the FAR to provide standardized cybersecurity contractual requirements across Federal agencies for Federal information systems (FIS) by implementing: (1) recommendations received in accordance with paragraph (i) of section 2 of Executive Order (E.O.) 14028, "Improving the Nation's Cybersecurity," dated May 12, 2021; and (2) paragraphs (a) and (b)(1) of section 7 of the Internet of Things (IoT) Cybersecurity Improvement Act of 2020 (Pub. L. 116-207). Other aspects of section 2 of E.O. 14028 are being implemented in FAR Case 2021-017, Cyber Threat and Incident Reporting and Information Sharing. This rulemaking does not implement Office of Management and Budget Memorandum M-22-18, Enhancing the Security of the Software Supply Chain through Secure Software Development Practices, issued September 14, 2022. The United States faces persistent and increasingly sophisticated malicious cyber campaigns that threaten the public and private sectors' security and privacy. The Council of Economic Advisors estimates that malicious cyber activity cost the U.S. economy between \$57 billion and \$109 billion in 2016. With threats continuing to grow, this activity could yield costs of more than \$1 trillion over a decade. In addition to the aggregate effect on the economy, the impact of a single cyber incident to an individual company can be crippling. An October 2020 study from the Cybersecurity and Infrastructure Security Agency (CISA) in the Department of Homeland Security (DHS), entitled "Cost of a Cyber Incident: Systematic Review and Cross-Validation," indicates that the average per-incident cost to small businesses of less than 250 employees and medium-sized businesses of at least 250 employees, but less than 1,000 employees, could range from \$5,000 to \$226,000, and from \$102,000 to \$40 million for large businesses of 1,000 employees or more. The Government must improve its efforts to identify, deter, protect against, detect, and respond to these actions. Contractors must be able to adapt to the continuously changing threat environment, ensure products are built and operate securely, and coordinate with the Government to foster a more secure cyberspace. It also is essential that the Government and its contractors take a coordinated approach to complying with applicable security and privacy requirements, which are closely related, though they come from independent and separate disciplines. In the end, the trust the United States places in its digital infrastructure should be proportional to how trustworthy and transparent that infrastructure is, and to the consequences it will incur if that trust is misplaced. The Government has a responsibility to protect and secure its computer systems, whether they are cloud-based, on-premises, or a hybrid of the two. The scope of that protection and security must encompass the systems that process data (e.g.,

(F) From subsection (e)(3) because the requirement that individuals supplying information be provided with a form stating the requirements of subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (G) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (H) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (I) From subsection (e)(5) because in the collection of information for law enforcement purposes it is impossible to determine in advance what information is accurate, relevant, timely, and complete. With the passage of time, (printed page 14748) seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light and the accuracy of such information can only be determined in a court of law. The restrictions of subsection (e)(5) would restrict the ability of trained investigators and intelligence analysts to exercise their judgment in reporting on investigations and impede the development of intelligence necessary for effective law enforcement. (J) From subsection (e)(8) because the individual notice requirements of subsection (e)(8) could present a serious impediment to law enforcement as this could interfere with the ability to issue search authorizations and could reveal investigative techniques and procedures. (K) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (L) From subsection (g) because portions of this system of records are compiled for law enforcement purposes and have been exempted from the access provisions of subsections (d) and (f). (7) System identifier and name. A0040-5b DASG, Army Public Health Data Repository (APHDR). (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he

would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source.

3.2.1 Chief Information Officer... 3.2.1 Chief Information Officer The Chief Information Officer (CIO) ensures that the organization's security posture is adequate.

AC.L2-3.1.9 · Privacy & Security Notices CMMC Assessment Guide · Level 2 | Version 2.13 34
AC.L2-3.1.9 · PRIVACY & SECURITY NOTICES Provide privacy and security notices consistent with applicable CUI rules. ASSESSMENT OBJECTIVES [NIST SP 800-171A]27 Determine if: [a] privacy and security notices required by CUI-specified rules are identified, consistent, and associated with the specific CUI category; and [b] privacy and security notices are displayed. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]27 Examine [SELECT FROM: Privacy and security policies, procedures addressing system use notification; documented approval of system use notification messages or banners; system audit logs and records; system design documentation; user acknowledgements of notification message or banner; system security plan; system use notification messages; system configuration settings and associated documentation; other relevant documents or records]. Interview [SELECT FROM: System or network administrators; personnel with information security responsibilities; personnel with responsibility for providing legal advice; system developers]. Test [SELECT FROM: Mechanisms implementing system use notification]. DISCUSSION [NIST SP 800-171 REV. 2]28 System use notifications can be implemented using messages or warning banners displayed before individuals log in to organizational systems. System use notifications are used only for access via logon interfaces with human users and are not required when such human interfaces do not exist. Based on a risk assessment, organizations consider whether a secondary system use notification is needed to access applications or other system resources after the initial network logon. Where necessary, posters or other printed materials may be used in lieu of an automated system banner. Organizations consult with the Office of General Counsel for legal review and approval of warning banner content. 27 NIST SP 800-171A, pp. 12-13. 28 NIST SP 800-171 Rev. 2, p. 13.

Although ·food· for purposes of section 306 of the Bioterrorism Act means the same as in section 201(f) of the FD&C Act, FDA is using its discretion to exclude some food from the record establishment and maintenance provisions. Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food contact substances other than the finished container that directly contacts the food are excluded from all the requirements of subpart J of this final rule, except §§ 1.361 and 1.363. Persons who place food directly in contact with its finished container are subject to all of the requirements of subpart J as to the finished container that directly contacts that food. All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that directly contacts the food are excluded from the requirements of subpart J as to the finished container, except the record access provisions for existing records under §§ 1.361 and 1.363. FDA determined that requiring such persons to establish and maintain records is not necessary in order to address credible threats of serious adverse health consequences or death to humans and animals. (Comment 62) One comment states that food packaging other than immediate food-contact packaging defined as ·food· in the FD&C Act should not be included within the scope of this final rule. This appears to be consistent with FDA's intent in that the term ·packaging· is neither defined nor used in the proposed rules. One comment states that the inner packaging that is in direct contact with the food provides a barrier to contamination from outer packaging components. Therefore, the comment agrees with FDA's conclusion that shipping containers and outer packaging not in direct contact with food poses only a small risk from contamination and should be omitted from recordkeeping requirements. One comment believes strongly that ·packaging· is not ·food· for purposes of the Bioterrorism Act. Even if FDA disagrees, the agency is urged to exclude from the recordkeeping obligation all (printed page 71586)

means an electronic computing device and electronic media stored in its immediate environment. Workstation includes but is not limited to the following types of devices: a server, desktop computer, laptop computer, virtual device, and mobile device such as a smart phone or tablet.
§ 164.306 Security standards: General rules. (a) General requirements. Each covered entity and business associate must do the following with respect to all electronic protected health information it creates, receives, maintains, or transmits: (1) Ensure the confidentiality, integrity, and availability of the electronic protected health information. (2) Protect against any reasonably

anticipated threats or hazards to the confidentiality, integrity, or availability of the electronic protected health information. (3) Protect against any reasonably anticipated uses or disclosures of the electronic protected health information that are not permitted or required under subpart E of this part. (4) Ensure compliance by its workforce with this subpart and all administrative, physical, and technical safeguards implemented in accordance with this subpart. (b) Flexibility of approach. (1) Covered entities and business associates may use any reasonable and appropriate security measures that allow the covered entity or business associate to implement the standards and implementation specifications as specified in this subpart. (2) In deciding which security measures to use, a covered entity or business associate must take into account all of the following factors: (i) The size, complexity, and capabilities of the covered entity or business associate. (ii) The covered entity's or the business associate's technical infrastructure, hardware, and software security capabilities. (iii) The costs of security measures. (iv) The probability and criticality of potential risks to electronic protected health information. (v) The effectiveness of the security measure in supporting the resiliency of the covered entity or business associate. (c) Standards and implementation specifications. A covered entity or business associate must comply with the applicable standards, including their implementation specifications, as provided in this subpart. § 164.308 Administrative safeguards. (a) A covered entity or business associate must, in accordance with §§ 164.306 and 164.316, implement all of the following administrative safeguards to protect the confidentiality, integrity, and availability of all electronic protected health information that it creates, receives, maintains, or transmits: (1) Standard: Technology asset inventory ·(i) General. Conduct and maintain an accurate and thorough written inventory and a network map of the covered entity's or business associate's electronic information systems and all technology assets that may affect the confidentiality, integrity, or availability of electronic protected health information. (ii) Implementation specifications ·(A) Inventory.

e pipeline that is experiencing a shortage, such as in the cybersecurity realm. Further, Cin-Day Cyber sponsored National Cybersecurity Career Awareness Week at area STEM middle and high schools. - d. The Cyber Prep Program developed more technically-focused two-year programs at community colleges that can be linked to bachelor's degree programs at four-year schools. These programs can meet local talent needs for information technology professionals with deep cybersecurity knowledge and curriculum updates can be approved more quickly and graduates are work-ready sooner because community colleges are responsive to employer demand. 4. To provide hands-on training to students and reduce the gap between education and job readiness, cybersecurity labs should be built through industry and academia collaborations. Development costs can be shared across multiple stakeholders, allowing both students and organizational employees to benefit from training in the laboratories. - a. The University at Albany built two cybersecurity and digital forensics teaching laboratories and two research laboratories in which they routinely worked with industry partners for both training and research. - b. The University at Albany also worked with New York State Information Technology Services (NYSITS) to build a cyber range that will help train employees at NYSITS and students in the one-year Master of Science program focused on Cyber Operations. - c. HRCyber assisted Old Dominion University with funding to expand its cybersecurity virtual lab and in opening it up to other educational institutions outside of the university network. This lab was able to provide a secure and user-

DoD has considered this comment and concludes that no further clarification is required in the final rule. The DoD Performance Based Payment Guide contains sufficient direction with regard to identifying PBP events, establishing completion criteria for PBP events, and establishing PBP event values. PBP events are established as representative milestones that may reflect the total effort needed to accomplish not only that particular milestone, but other activities through that timeframe; milestone events or criteria may be either severable or cumulative, and the contract should state which applies (FAR 32.1004(a)(2)). However, care must be taken to ensure that there is reasonable consistency in event valuation and that valuation of events is reflective of their relative value to the successful performance of the contract, so that the contractor's financial focus is in basic alignment with programmatic priorities. 9. Training and Guidance Several respondents recommended additional training and guidance on PBPs to both program managers and contracting officers. a. PBP process. Comment: One respondent recommended training on the PBP milestone process because the respondent has encountered reluctance on the part of the Government due to lack of experience in use of PBPs and concern for administrative burden on the Government. Another respondent noted that establishing proper milestones requires an understanding of what it takes to perform the contract and how much it will cost. However, it also requires understanding of

how (printed page 19686) businesses operate and why they need certain funding when they do. Therefore, the respondent recommended guidance and training to procurement personnel on how to reach the proper balance between DoD and contractor needs. Response: Each DFARS case is reviewed for training requirements/changes to current Defense Acquisition University training. In addition to the Continuing Learning Course (CLC 026), Performance Based Payment Overview, the Performance Based Payment Guide, and Guide for Performance Based Service Acquisitions, courses in the Contracting and Program Management curriculum contain appropriate information on PBPs to align with course goals. The changes in the DFARS will prompt changes in the guides and course to ensure the workforce understands the processes. b. Cash flow. Comment: One respondent recommended guidance to contracting officers that a slightly positive cash flow is acceptable and encouraged, since it further incentivizes performance. Another respondent when addressing training also noted that limiting reasonable cash flow to contractors may result in deferring expenditures, which could result in late delivery. Response:

Investigatory information compiled for law-enforcement purposes by non-law enforcement activities and which is not within the scope of § 310.51(a). If an individual is denied any right, privilege or benefit that he or she is otherwise entitled by federal law or for which he or she would otherwise be eligible as a result of the maintenance of the information, the individual will be provided access to the information except to the extent that disclosure would reveal the identity of a confidential source. This subsection when claimed allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (3) Exemption (k)(3). Records maintained in connection with providing protective services to the President and other individuals identified under 18 U.S.C. 3506 . (4) Exemption (k)(4). Records maintained solely for statistical research or program evaluation purposes and which are not used to make decisions on the rights, benefits, or entitlement of an individual except for census records which may be disclosed under 13 U.S.C. 8 . (5) Exemption (k)(5). Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information, but only to the extent such material would reveal the identity of a confidential source. This provision allows protection of confidential sources used in background investigations, employment inquiries, and similar inquiries that are for personnel screening to determine suitability, eligibility, or qualifications. (6) Exemption (k)(6). Testing or examination material used solely to determine individual qualifications for appointment or promotion in the federal or military service, if the disclosure would compromise the objectivity or fairness of the test or examination process. (7) Exemption (k)(7). Evaluation material used to determine potential for promotion in the Military Services, but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (c) All systems of records maintained by the NSA/CSS and its components shall be exempt from the requirements of 5 U.S.C. 552a(d) pursuant to 5 U.S.C. 552a(k)(1) to the extent that the system contains any information properly classified under Executive Order 12958 and that is required by Executive Order to be kept secret in the interest of national defense or foreign policy. This exemption is applicable to parts of all systems of records including those not otherwise specifically designated for exemptions herein, which contain isolated items of properly classified information. (1) System identifier and name. GNSA 01, Access, Authority and Release of Information File. (i) Exemption.

DCMA DIBCAC will perform a Level 3 certification assessment in accordance with NIST SP 800-171A Jun2018 (incorporated by reference, see § 170.2) and NIST SP 800-172A Mar2022 (incorporated by reference, see § 170.2) and the CMMC Level 3 scoping requirements set forth in § 170.19(d) for the information systems within the CMMC Assessment Scope. The Level 3 certification assessment will be scored in accordance with the CMMC Scoring Methodology set forth in § 170.24 and DCMA DIBCAC will upload the results into the CMMC instantiation of eMASS. Final results are communicated to the OSC through a CMMC Assessment Findings Report. For assets that changed asset category (i.e., CRMA to CUI Asset) or assessment requirements (i.e., Specialized Assets) between the Level 2 and Level 3 certification assessments, DCMA DIBCAC will perform limited checks of Level 2 security requirements. If the OSC had these upgraded asset categories included in their Level 2 certification assessment, then DCMA DIBCAC may still perform limited checks for compliance. If DCMA DIBCAC identifies that a Level 2 security requirement is NOT MET, the Level 3 assessment process may be paused to allow for remediation, placed on hold, or immediately terminated. (2) Security requirement re-evaluation. A security requirement that is NOT MET (as defined in § 170.24) may be re-evaluated during the course of the Level 3 certification assessment and for 10 business days following the active assessment

period if all of the following conditions exist: (i) Additional evidence is available to demonstrate the security requirement has been MET; (ii) The additional evidence does not materially impact previously assessed security requirements; and (iii) The CMMC Assessment Findings Report has not been delivered. (3) POA&M. If a POA&M exists, a POA&M closeout certification assessment will be performed by DCMA DIBCAC within 180-days of the Conditional CMMC Status Date. Additional guidance is located in §.170.21 and in the guidance document listed in paragraph (d) of appendix A to this part. (4) Artifact retention and integrity. The hashed artifacts used as evidence for the assessment must be retained by the OSC for six (6) years from the CMMC Status Date. The hashed artifacts used as evidence for the assessment must be retained by the OSC for six (6) years from the CMMC Status Date. To ensure that the artifacts have not been altered, the OSC must hash the artifact files using a NIST-approved hashing algorithm. Assessors will collect the list of the artifact names, the return value of the hashing algorithm, and the hashing algorithm used and upload that data into the CMMC instantiation of eMASS. Additional guidance for hashing artifacts can be found in the guidance document listed in paragraph (h) of appendix A to this part. (5) Level 3 certification assessment with the use of Cloud Service Provider (CSP).

(a) Protection of FCI and CUI on contractor information systems is of paramount importance to the DoD and can directly impact its ability to successfully conduct essential missions and functions. It is DoD policy that defense contractors and subcontractors shall be required to safeguard FCI and CUI that is processed, stored, or transmitted on contractor information systems by applying specified security requirements. In addition, defense contractors and subcontractors may be required to implement additional safeguards defined in NIST SP 800-172 Feb2021 (incorporated by reference, see §.170.2), implementing DoD specified parameters to meet CMMC Level 3 security requirements (see table 1 to §.170.14(c)(4)). These additional requirements are necessary to protect CUI being processed, stored, or transmitted in contractor information systems, when designated by a requirement for CMMC Status of Level 3 (DIBCAC) as defined by a DoD program manager or requiring activity. In general, the Department will identify a requirement for a CMMC Status of Level 3 (DIBCAC) for solicitations and resulting contracts supporting its most critical programs and technologies. (b) Program managers and requiring activities are responsible for identifying the CMMC Status that will apply to a procurement. Selection of the applicable CMMC Status will be based on factors including but not limited to: (1) Criticality of the associated mission capability; (2) Type of acquisition program or technology; (3) Threat of loss of the FCI or CUI to be shared or generated in relation to the effort; (4) Impacts from exploitation of information security deficiencies; and (5) Other relevant policies and factors, including Milestone Decision Authority guidance. (c) In accordance with the implementation plan described in §.170.3, CMMC Program requirements will apply to new DoD solicitations and contracts, and shall flow down to subcontractors who will process, store, or transmit FCI or CUI in performance of the subcontract, as described in §.170.23. (d) In very limited circumstances, and in accordance with all applicable policies, procedures, and requirements, a Service Acquisition Executive or Component Acquisition Executive in the DoD, or as delegated, may elect to waive inclusion of CMMC Program requirements in a solicitation or contract. In such cases, contractors and subcontractors will remain obligated to comply with all applicable cybersecurity and information security requirements. (e) The CMMC Program does not alter any separately applicable requirements to protect FCI or CUI, including those requirements in accordance with 48 CFR 52.204-21 , Basic Safeguarding of Covered Contractor Information Systems, or covered defense information in accordance with 48 CFR 252.204-7012 , Safeguarding Covered Defense Information and Cyber Incident Reporting,

----- | Maturity Level 1: Policy.

Does documented policy require controls such as separation of duties, least privilege, and individual accountability incorporated into all business operations? | Yes - Policy Document , Chapter 6 part 5.2 shall provide access to Organization's information systems according to individual accountability, separation of duties, and the least privilege practice. | Compliant | | Maturity Level 2: Procedures. Are procedures documented for incorporating controls such as separation of duties, least privilege, and individual accountability incorporated into all business operations? | Yes - Chapter 2 part 1.2 The Internet Posting Process provides instruction as to where, how, when, and who incorporates controls for separation of duties, least privilege, and individual accountability for posting to the Internet. This document provides a partial compliance since other functions need such procedures. | Partially Compliant | This procedure applies only to Internet posting; other events are necessary to provide complete compliance. | | Maturity Level 3:

Implementation. Are controls such as separation of duties, least privilege, and individual accountability incorporated into all business operations? | Yes, Section 3.3.1.1 provides general assignment of information security responsibilities based on principles of separation of duties, least privilege and individual accountability. Section 3.3.6.1 states System "X" separated users into two primary categories: superusers and users. Superusers are subdivided into 4 types: AAs, EC Reviewers, SAs, and DBAs.

(iii) Establish a continuous receipt system for the transmittal of TOP SECRET information within and outside the contractor location. (iv) Number each item of TOP SECRET material in a series. Place the copy number on TOP SECRET documents, regardless of media, and on all associated transactions documents. (v) Establish a record of TOP SECRET material when the material is: (A) Completed as a finished document. (B) Retained for more than 180 days after creation, regardless of the stage of development. (C) Transmitted outside the contractor location. (vi) Establish procedures for destruction of TOP SECRET material by two authorized persons. (vii) Establish destruction records for TOP SECRET material and maintain the records for two years in accordance with § 117.13(d)(5) or in accordance with GCA requirements. (3) Working papers. Contractors will establish procedures for the control of classified working papers generated in the preparation of a finished document. The contractor will: (i) Date working papers when they are created. (ii) Mark each page of the working papers with the highest classification level of any information contained in them and with the annotation "WORKING PAPERS." (iii) Destroy working papers when no longer needed. (iv) Mark in the same manner prescribed for a finished document at the same classification level if released outside the contractor location or retained for more than 180 days from the date of origin. (4) Combinations to locks. Contractors will follow the guidance in 32 CFR 2001.45(a)(1) and 2001.43(c) to address thresholds when combinations will be changed. Combinations to locks used to secure vaults, open storage areas, and security containers that are approved for the safeguarding of classified information will be protected in the same manner as the highest level of classified information that the vault, open storage area, or security container is used to protect. (5) Information system passwords. Contractors will follow the guidance established in 32 CFR 2001.45(a)(2) for the protection of passwords to information systems authorized to process and store classified information at the highest level of classification to which the information system is authorized. (6) Reproduction of classified information. Contractors will follow the guidance established in 32 CFR 2001.45(b) for the reproduction of classified information. (f) Transmission of classified information. Contractors will establish procedures for transmitting and receiving classified information and material in accordance with 32 CFR 2001.46. (1) Top secret. The contractor must have written authorization from the GCA to transmit TOP SECRET material outside the contractor location. (2) Transmission outside the United States and its Territorial Areas. The contractor may transmit classified material to a USG activity outside the United States or a U.S. territorial area only under the provisions of a classified contract or with written authorization from the GCA. (3) Commercial delivery entities.

(3) Inspects and monitors contractor, licensee, certificate holder, and grantee programs and facilities that involve access to information under NRC programs classified pursuant to the AEA, other federal statutes, and executive orders where appropriate. (e) DNI. In addition to the responsibilities in paragraph (h) of this section, the DNI: (1) Prescribes procedures for the portions of this rule pertaining to intelligence sources, methods, and activities, including, but not limited to, SCI. (2) Retains authority over access to intelligence sources, methods, and activities, including SCI. (3) Provides guidance on the security requirements for intelligence sources and methods of information, including, but not limited to, SCI. (f) Secretary of Homeland Security. In accordance with E.O. 12829, E.O. 13691, and in addition to the responsibilities in paragraph (h) of this section, the Secretary of Homeland Security: (1) Prescribes procedures for the portions of this rule that pertain to the CCIPP. (2) Retains authority over access to information under the CCIPP. (3) Inspects and monitors contractor, licensee, certificate holder, and grantee programs and facilities that involve access to CCIPP. (g) All the CSA heads. The CSA heads: (1) Oversee the security of classified contracts and activities under their purview. (2) Provide oversight of contractors under their security cognizance. (3) Minimize redundant and duplicative security review and audit activities of contractors, including such activities conducted at contractor locations where multiple CSAs have equities. (4) Execute appropriate intra-agency and inter-agency agreements to avoid redundant and duplicate reviews. (5) Designate one or more CSOs for security administration. (6) Designate subordinate officials, in accordance with governing policies, to act as the authorizing official. Authorizing officials will: (i) Assess and authorize

contractors to process classified information on information systems. (ii) Conduct oversight of such information system processing and provide information system security guidelines in accordance with Federal information system security control policies, standards, and procedures. Minimize redundant and duplicative security review and audit activity of contractors, including such activity conducted at contractor locations where multiple CSAs have equities. (h) Heads of component agencies. In accordance with applicable CSA direction, the component agency heads: (1) Oversee compliance with procedures identified by the applicable CSA or designated CSO. (2) Provide oversight of contractor personnel visiting or working on USG installations. (3) Promptly apprise the CSO of information received or developed that could adversely affect a cleared contractor, licensee, or grantee, and their employees, to hold an FCL or PCL, or that otherwise raises substantive doubt about their ability to safeguard classified information entrusted to them.

The Army's rules for accessing records and for contesting contents and appealing initial agency determinations are contained in Army Regulation 340-21; 32 CFR part 505 ; or may be obtained from the system manager. Record source categories: From individuals. Exemptions claimed for the system: None. Deletion of System Notice DEPARTMENT OF DEFENSE Office of the Secretary Privacy Act of 1974; System of Records AGENCY: Office of the Secretary, DoD. ACTION: Notice to delete systems of records. SUMMARY: The Office of the Secretary of Defense is deleting a system of records notice from its existing inventory of records systems subject to the Privacy Act of 1974, (5 U.S.C. 552a), as amended. DATES: This proposed action will be effective without further notice on (insert date thirty days after publication in Federal Register) unless comments are received which result in a contrary determination. ADDRESSES: OSD Privacy Act Coordinator, Records Management Section, Washington Headquarters Services, 1155 Defense Pentagon, Washington, DC 20301-1155. FOR FURTHER INFORMATION CONTACT: Ms. Mary Smith at (703) 000-0000. SUPPLEMENTARY INFORMATION: The Office of the Secretary of Defense systems of records notices subject to the Privacy Act of 1974, (5 U.S.C. 552a), as amended, have been published in the Federal Register and are available from the address above. The specific changes to the records system being amended are set forth below followed by the notice, as amended, published in its entirety. The proposed amendments are not within the purview of subsection (r) of the Privacy Act of 1974, (5 U.S.C. 552a), as amended, which requires the submission of a new or altered system report. Dated: April 2, 2006. John Miller, OSD Federal Register Liaison Officer, Department of Defense. (printed page 18790) DODDS 27 System name: DoD Domestic and Elementary School Employee File (May 9, 2003, 68 FR 24935). Reason: The records contained in this system of records are covered by OPM/GOVT-1 (General Personnel Records), a government-wide system notice. Appendix H to Part 310-Litigation Status Sheet (See §-310.49) Litigation Status Sheet 1. Case Number [1] 2. Requester 3. Document Title or Description [2] 4. Litigation a. Date Complaint Filed b. Court c. Case File Number 1 5. Defendants (DoD Component and individual) 6. Remarks (brief explanation of what the case is about) 7. Court Action a. Court's Finding b. Disciplinary Action (as appropriate) 8. Appeal (as appropriate) a. Date Complaint Filed b. Court c. Case File Number d. Court's Finding e. Disciplinary Action (as appropriate) Dated: March 28, 2007. L.M. Bynum, Alternate OSD Federal Register Liaison Officer, DoD. Footnotes 1. ·Copies may be obtained at <http://www.dtic.mil/-whs/-directives> . Back to Citation 2. ·See footnote 1 to §-310.1. Back to Citation 3. ·See footnote 1 to §-310.3(c)(1). Back to Citation 4. ·See footnote 1 to §-310.3(c)(1). Back to Citation 5. ·See footnote 1 to §-310.1. Back to Citation 6. ·See footnote 1 to §-310.1. Back to Citation 7. ·See footnote 1 to §-310.1.

An organization's training program should be an ongoing, evolving process and flexible enough to educate workforce members on new cybersecurity threats and how to respond to them. As such, regulated entities should consider how often to train workforce members on security issues, given the risks and threats to their enterprises, and how often to send security updates to their workforce members. Many regulated entities have determined that twice-annual training and monthly security updates are necessary, given their risks analyses. Regulated entities should apply security updates and reminders to quickly communicate new and emerging cybersecurity threats to workforce members such as new social engineering ploys (e.g., fake tech support requests and new phishing scams) and malicious software attacks including new ransomware variants. Entities need to address what type of training to provide to workforce members on security issues, given the risks and threats to their enterprises. Computer-based training, classroom training, monthly newsletters, posters, email alerts, and team discussions are all tools that different organizations use to fulfill their training requirements. Entities must also address how to document that training to workforce members was provided, including dates and types of training, training materials, and

evidence of workforce participation. HHS has issued many types of training materials on securing PHI. [581] NIST has also provided detailed guidance for developing and implementing workforce training programs. [582] Despite this existing guidance, regulated entities often fail to provide appropriate training to adequately safeguard ePHI. For example, in one investigation, OCR investigators found evidence that not only had an ambulance company potentially failed to conduct a risk analysis, it also potentially failed to implement a security training program or to train any of its employees. [583] Such failures can contribute to breaches of individuals' unsecured ePHI. To ensure security awareness training compliance, a regulated entity needs to regularly educate its workforce members on the evolving technological threats to ePHI, how to use the technology that the regulated entity has adopted and implemented, and the specific procedures workforce members must follow to ensure that the ePHI remains protected. Additionally, while many educational programs for clinicians provide general training on the HIPAA Rules, the curriculums vary widely. Without providing its own training on the Security Rule, a regulated entity cannot ensure that the training its workforce received elsewhere meets the required standards.

H. Comments on What Information is Required in the Records You Must Establish and Maintain to Identify the Nontransporter and Transporter Immediate Previous Sources and Immediate Subsequent Recipients? (Proposed §§ 1.337 and 1.345) 1. General Comments (Comment 87) Several comments state that the information required by the recordkeeping regulations exceeds the information required by the Bioterrorism Act, thereby exceeding FDA's statutory authority. Some of these comments state that according to the Bioterrorism Act, the regulations need to provide that those persons subject to the recordkeeping requirement maintain the 'one-up and one-back' information in a records maintenance system in which the information is reasonably accessible to FDA upon request. The comments ask that FDA consider the diversity and complexity of the food industry and allow for more flexibility. They contend that the name and address of the person from whom an article of food was received or to whom it was shipped and a description of the article of food should be sufficient. The comments further suggest that not all companies require or need the same type of identification as other members in the food chain, e.g., lot numbers and identity preserved ingredients. They request that, because of this diversity in the supply chain, the agency not define rigid identification requirements. The comments contend that this flexibility is in keeping with the intent of the Bioterrorism Act and will avoid dramatic changes to what are currently efficient and effective business practices. (Response) FDA disagrees that the information required by the rule exceeds FDA's authority under the Bioterrorism Act. The Bioterrorism Act authorizes FDA to require records needed to 'allow the Secretary to identify the immediate previous sources and immediate subsequent recipients of food, including its packaging, in order to address credible threats of serious adverse health consequences or death in humans or animals.' FDA believes the information it is requiring to be (printed page 71596) established and maintained meets this standard.

dent [13] information are currently being developed in the IETF Managed Incident Lightweight Exchange (MILE) [14] and the IETF Security Automation and Continuous Monitoring (SACM) [15] working groups. A ROLIE repository discovery mechanism [16] and a JSON-based version of ROLIE are also being developed in IETF MILE. Once completed, these solutions will be implemented in the NVD, and can be implemented by vendors to support SCAP content discovery and exchange. - NIST IR 8085: In support of the transition from CPE to SWID, an automated method is needed to support the generation of a CPE Name from a SWID tag to support legacy SCAP v1 tools. Draft NISTIR 8085 [17] is a start to support generation of CPE names from SWIDs, but more work is needed to complete this specification.

By limiting these exceptions to devices that have been updated and/or patched while they were supported by their manufacturer, we believe that this proposal would balance the interest in encouraging regulated entities to dispense with legacy devices with the cost of replacing such devices. Additionally, the Department believes that regulated entities should already have plans to replace legacy devices that cannot be made cybersecure because of their existing Security Rule obligations. As discussed above, we also recognize that at some point, most, if not all, devices will likely become legacy devices and that there may be legitimate reasons not to immediately replace them when the manufacturer ceases to provide support. In such cases, it will continue to be important for regulated entities to plan for how to address their ongoing Security Rule obligations. The third proposed exception to MFA at 45 CFR 164.312(f)(2)(iii)(C) (3) for devices authorized by the FDA for marketing would be available for those devices authorized for marketing by the FDA pursuant to a submission received on or after March 29, 2023, where they are supported by their manufacturer. We understand that the FDA considers security during the review of medical device

marketing submissions and works with device manufacturers to ensure that appropriate cybersecurity protections are built into such devices, pursuant to FDA's authority under the Consolidated Appropriations Act, 2023. [784] Thus, we do not believe it would be necessary or appropriate for the Security Rule to require MFA for an FDA-authorized medical device that has been authorized by FDA for marketing pursuant to a submission received on or after March 29, 2023, where the device continues to be supported by its manufacturer. However, these devices may continue to be used by a regulated entity when they are no longer supported, consistent with the proposed exception for legacy devices that were approved pursuant to a submission received on or after March 29, 2023, as described above. Where a proposed exception would apply to the proposed MFA requirement, the Department proposes to require that a regulated entity implement alternative measures and compensating controls. [785] Specifically, when a regulated entity seeks to comply with the Security Rule by meeting one of the proposed exceptions to the proposed MFA requirement, the Department proposes to require a regulated entity to document both the existence of the criteria demonstrating that the proposed exception would apply and the rationale for why the proposed exception would apply. (printed page 976) Additionally, the proposal would require a regulated entity to implement reasonable and appropriate compensating controls, as described at proposed paragraph (f)(2)(iv)(B). The proposed requirements for reasonable and appropriate compensating controls are explained under proposed 45 CFR 164.312(f)(2)(iv)(B)

The Department makes the determination that such modifications may be needed using information it receives on an ongoing basis from the Department's Federal advisory committee on HIPAA, the public, regulated entities, media reports, and its own analysis of the state of privacy and security for IIHI. As referenced above, and discussed in greater detail below, while the Department believes that the Security Rule generally continues to accomplish the goals of HIPAA, [20] we believe that it would be appropriate to consider modifying the Security Rule to address the following:

Significant changes in technology. Changes in breach trends and cyberattacks. HHS' Office for Civil Rights' (OCR's) enforcement experience. Other guidelines, best practices, methodologies, procedures, and processes for protecting ePHI. Court decisions that affect enforcement of the Security Rule.

B. Applicability The effective date of a final rule would be 60 days after publication. [21] Regulated entities would have until the compliance date to establish and implement policies, procedures, and practices to achieve compliance with any new or modified standards. (printed page 901) Regulated entities would be permitted to comply earlier than the compliance date, but the Department would not take action against them for noncompliance with the proposed changes that occurs before the compliance date. Except as otherwise provided, 45 CFR 160.105 provides that regulated entities must comply with the applicable new or modified standards or implementation specifications no later than 180 days from the effective date of any such change. The Department has previously noted that the 180-day general compliance period for new or modified standards would not apply where a different compliance period is provided in the regulation for one or more provisions. [22] However, the compliance period cannot be less than the statutory minimum of 180 days. [23]

(i) That the Secretary of Defense, in coordination with the Secretary of State, shall prescribe regulations on the selection, training, equipping, and conduct of personnel performing private security functions under a covered contract in an area of combat operations or other significant military operations; and (ii) That the FAR shall be revised to require the insertion into each covered contract (or, in the case of a task order, the contract under which the task order is issued) of a contract clause addressing the selection, training, equipping, and conduct of personnel performing private security functions under such contract. This Final Rule meets requirement (i). There will be a separate and subsequent Federal Register action to meet requirement (ii) to update the FAR. On July 17, 2009, an Interim Final Rule (32 CFR Part 159 DOD-2008-OS-125/RIN 0790-AI38) was published and public comments were solicited. At the end of the comment period, we received comments from 9 respondents, including the American Bar Association, IPOA, NGO groups and members of the public. These comments are discussed below by topic. Comment: Extent of Delegation of Implementation Authority to Each Geographic Combatant Commander Response: We believe that it is appropriate for DoD to provide the Geographic Combatant Commanders with the requirements to be included in their respective guidance and procedures. Situations change significantly from one geographic region to another. The Geographic Combatant Commanders (GCC) must have the flexibility to apply the overarching policy, tailoring their guidance and procedures as necessary to meet the particular circumstances within their respective areas of responsibility at any particular time. This is consistent with the approach that we are currently taking in the CENTCOM Area Of

Responsibility (AOR) without significant issue. We do not believe that differing or conflicting regulations will be adopted within a single AOR. The GCC will establish the overarching guidance and Subordinate Commanders (down to Joint Task Force level) will develop implementing instructions. Specific requirements will be made available to Private Security Contractors through the GCC Web site. Comment: Absence of Department-Wide Guidance Response: We believe that a de-centralized approach is the most appropriate way to implement the requirements of Section 862 of the FY08 NDAA. There is sufficient uniformity of guidance provided through policy, including this Rule and existing acquisition regulations. The intent of the policy is that all PSC personnel operating within the designated area are required to have the required training, not only those who are deploying. A FAR case has been opened to incorporate the required revisions based upon the publication of this Final Rule. Comment: Lack of Uniformity Across Organizations Response:

DoD internal policies, procedures, and approval requirements will govern the process for DoD to waive inclusion of the CMMC requirement in the solicitation. Once applicable to a solicitation, there is no process for OSAs to seek waivers of CMMC requirements from the DoD CIO. In accordance with § 170.5(d), a limited waiver authority is provided to the Acquisition Executive with acquisition oversight for the program in question. These officials may issue supplemental guidance dictating specific coordination requirements for waiver requests. Recommended administrative changes have been incorporated into § 170.5(d) to add clarity. 11. Determination of Applicable Assessment Type a. Process for Level Determination Comment: Multiple comments asked how DoD will determine the CMMC level to include in solicitations. Multiple comments inquired about the criteria DoD will use to determine when to require a CMMC Level 2 self-assessment, CMMC Level 2 certification, or CMMC Level 3 certification assessment. Multiple comments asked specifically about when CMMC Level 2 self-assessment will be required versus CMMC Level 2 Certification. One comment requested more information on which companies may self-attest. One comment requested § 170.5(a) be modified to prevent CMMC level 2 or 3 being assigned for contracts where only FCI is exchanged. One comment emphasized that requirement(s) for Contractor certification levels must be the same as stated throughout this proposed ruling. Two comments recommended providing contracting officers with interim guidance to ensure consistency in applying CMMC requirements. One comment requested the detailed guidance ensure CMMC requirements are selected based on risk, and that certification is not required by default. Some commenters objected to the wording of one criterion for level selection as potential for and impacts from exploitation of information security deficiencies. One asserted this equates to a sub-CONFIDENTIAL security classification. One comment expressed that all information systems that process CUI should have the same level of program criticality, information sensitivity, and the severity of cyber threat since CUI is Unclassified Information which is a handling caveat. Multiple comments requested a clearer description of what contracts require CMMC Level 3 Certification, one of which requested a definition of what constitutes a priority program that might require CMMC Level 3. One comment requested that acquisition processes first analyze the CUI for a proposed effort using published factors for aligning CUI to high value assets before setting CMMC levels. They asserted use of such published factors would improve accuracy of CUI marking. (printed page 83115) Response: Pre-award contracting procedures and processes for CMMC assessment requirements will be addressed in the 48 CFR part 204

DFARS 252.204-7020 (NIST SP 800-171 DoD Assessment Requirements) Requires contractors to have current NIST SP 800-171 DoD Assessment for Medium and High assessment levels. Non-compliance with 252.204-7020 can result in: loss of contract eligibility, termination for cause, False Claims Act liability (if contractor misrepresented compliance status), suspension or debarment from future DoD contracting, and in cases involving CUI spillage or breach, potential civil or criminal penalties.

functionality) - The human aspect (social engineering) - Theft of intell property - Theft of IP - Treats to RF spectrum - wireless is increasing the comms component of choice on factory floor. 802.3, 802.11ad etc - Understanding 3D printer, direct digital in the context of 3D phenomenon [i.e. same files could be used for manufacturing or decision support - Uneducated workforce

Cryptography is foundational to our security and data protection needs. The standards, guidelines, recommendations, and tools provided by NIST's Cryptography priority area enable the trustworthy assurance of integrity and confidentiality in all types of information and technology - now and in the future. - NIST launched the hardware security program to identify existing and emerging cybersecurity threats and develop mitigation techniques for semiconductors, including cybersecurity

(D) From subsection (e)(1) because the nature of the criminal and/or civil investigative function creates unique problems in prescribing a specific parameter in a particular case with respect to what information is relevant or necessary. Also, information may be received which may relate to a case under the investigative jurisdiction of another agency. The maintenance of this information may be necessary to provide leads for appropriate law enforcement purposes and to establish patterns of activity that may relate to the jurisdiction of other cooperating agencies. (E) From subsection (e)(2) because in a criminal investigation, the requirement that information be collected to the greatest extent possible from the subject individual would present a serious impediment to law enforcement in that the subject of the investigation would be placed on notice of the existence of the investigation and would therefore be able to avoid detection. (F) From subsection (e)(3) because the requirement that individuals supplying information be provided with a form stating the requirements of subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (G) From subsections (e)(4)(G) and (e)(4)(H) because the requirements in those subsections are inapplicable to the extent that portions of this system of records may be exempt from subsection (d), concerning individual access. (H) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (I) From subsection (e)(5) because in the collection of information for law enforcement purposes, it is impossible to determine in advance what information is accurate, relevant, timely, and complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light and the accuracy of such information can only be determined in a court of law. The restrictions of subsection (e)(5) would restrict the ability of trained investigators and intelligence analysts to exercise their judgment in reporting on investigations and impede the development of intelligence necessary for effective law enforcement. (J) From subsection (e)(8) because the individual notice requirements of subsection (e)(8) could present a serious impediment to law enforcement as this could interfere with the ability to issue search authorizations and could reveal investigative techniques and procedures. (K) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d).

BGP origin validation relies on a global RPKI system (e.g., certificate authorities, publication repositories, etc.) as the source of trusted information about internet address holders and their route origin authorization statements. Each RIR operates a trusted root certificate authority (CA) in the RPKI system and publishes a Certificate Practice Statement [RFC7382] describing the security and robustness properties of each implementation. Each RPKI CA has integrity and authentication mechanisms for data creation, storage, and transmission. Nevertheless, compromise of the underlying servers and/or registry services is still a potential, if low probability, threat. Making security recommendations for mitigating against such threats is outside of the scope of this document. DDoS threats involving vulnerable applications using various UDP/TCP ports and IoT devices are continually evolving and varied (e.g., memcached DDoS reflection attacks and SSDP diffraction, etc. [Bjarnason] [Arbor2]). Hence, traffic filtering methods mentioned in this section are not meant to be exhaustive. | References | |-----|-----

--|| [Acunetix] | 'Prevention of NTP Reflection DDoS attacks based on CVE-2013-5211,' Acunetix blog, September 2014.

Because each organization has unique security needs, security products have been applied on a case by case basis to meet individual security threats and concerns. Products should be flexible enough to serve a broad spectrum of security needs at the operating system level, the application level, the organizational level, and the site level. Organizational security requirements also change over time and cannot be totally specified at the time of product acquisition. Protecting the privacy of personal information was also relevant to commercial sector organizations. The need to protect sensitive data from unauthorized access resulted from operational environment (including threats) and data sensitivity factors. These factors include legal obligations and self-imposed requirements including confidentiality of salary, performance, and health (mental, drug, and alcohol related illness) , as well as data involving legal incidents. The study team found that a computerized hospital support system, whether in a VA or commercial hospital, also imposes stringent integrity controls. The integrity controls of such a system must provide for the ethics and laws associated with the clinical treatment of patients. Prior diagnoses can never be destroyed or altered; only doctors can perform a diagnosis and prescribe medicine. Protecting the accuracy of patients medical records may be critical if there is an accident where the patient becomes unconscious. The correctness of information including the patient's reaction to medications, pre-existing ailments, blood type, or medication currently being prescribed can all prove to be healththreatening or even life-threatening.

(ii) The System Manager shall include the summary of the NGB's reasons for not making a correction when disclosing disputed information. (5) Copies of the statement summarizing the reasons for the NGB refusing to amend the records will be treated as part of the individual's record; however, it will not be subject to the amendment procedure outlined in 5 U.S.C. 552 and 32 CFR part 310, subpart D . (h) Penalties. (1) Civil Action. An individual may file a civil suit against the NGB or its employees if the individual feels certain provisions of 5 U.S.C. 552a have been violated. (2) Criminal Action. (i) Criminal penalties may be imposed against any officer or employee for the offenses listed in subsection I of 5 U.S.C. 552a . (ii) An officer or employee of NGB may be found guilty of a misdemeanor and fined up to \$5,000 for a violation of the offenses listed in subsection I of 5 U.S.C. 552a . (i) Litigation Status Sheet. Whenever a complaint citing 5 U.S.C. 552a is filed in a U.S. District Court against the NGB, or any employee of NGB, the Chief of Litigation and Employment Law shall: (1) Promptly notify the Chief of the OIP of the complaint using the litigation status sheet in 32 CFR part 310, Appendix H . This status sheet will be provided to the DPCLO, or the respective service(s) involved in the litigation. (2) Provide a revised litigation status sheet to the Chief of the OIP at each stage of the litigation for submission to the DPCLO, or the respective service(s) involved. (3) When a court renders a formal opinion or judgment, copies of the judgment or opinion shall be provided to the Chief of the OIP who will provide them to DPCLO, or the respective service(s) involved, along with the litigation status sheet reporting the judgment or opinion. (j) Computer Matching Programs. All requests for participation in a matching program (either as a matching agency, or a source agency) shall be submitted directly to the DPCLO for review and compliance, following procedures in 32 CFR part 310, subpart L . The Directorate shall submit a courtesy copy of such requests to the Chief of the OIP. §329.7 Exemptions. (a) General Information. There are two types of exemptions, general and specific. The general exemption authorizes the exemption of a SOR from all but a few requirements of 5 U.S.C. 552a . The specific exemption authorizes exemption of a SOR or portion thereof, from only a few specific requirements. If a new SOR originates for which an exemption is proposed, or an additional or new exemption for an existing SOR is proposed, the exemption shall be submitted with the SORN. No exemption of a SOR shall be considered automatic for all records in the system. The System Manager shall review each requested records and apply the exemptions only when this will serve significant and legitimate purpose of the Federal Government. (b) Exemption for Classified Material. All SOR maintained by the NGB shall be exempt under section (k)(1) of 5 U.S.C. 552a

- · Automatically checking for and acquiring updates of signature or data definition files at least daily; - · Scanning critical OS components, such as startup files, system basic input/output system (BIOS), and boot records; - · Monitoring the behavior of common applications, such as email clients, web browsers, file transfer and file sharing programs, and instant messaging software; - ·

Performing real-time scans of each file as it is downloaded, opened, or executed; - · Scanning all hard drives regularly to identify any file system infections, and optionally scanning removable media as well; - · Handling files that are infected by attempting to disinfect them, which refers to removing malware from within a file, and quarantining them, which means that files containing malware are stored in isolation for future disinfection or examination; and - · Logging all significant events, such as the results of scans, the startup and shutdown of antivirus software, the installation of updates, and the discovery and handling of any instances of malware.

NIST is selecting public-key cryptographic algorithms through a public, competition-like process to specify additional digital signature, public-key encryption, and key-establishment algorithms to supplement FIPS 186-5, SP 800-56Ar3, and SP 800-56Br2. These algorithms are intended to protect sensitive information well into the foreseeable future, including after the advent of quantum computers. In the fourth round of the Post-Quantum Cryptography Standardization Process, NIST selected four candidate algorithms for key establishment to be studied: BIKE, Classic McEliece, HQC, and SIKE. This report describes the evaluation and selection process of these fourth-round candidates based on public feedback and internal review. The report summarizes each of the candidate algorithms and identifies those selected for standardization. The only key-establishment algorithm that will be standardized is HQC, and NIST will develop a standard based on HQC to augment its key-establishment portfolio. | 1. Introduction | . . . |

1 | |-----|-----
-----	-----
-----|----- | 1.1. | Purpose and Organization of This Document
. . . | 3 | | 2. Evaluation Criteria and Selection Process . . | | 4 | | 2.1. |
Acceptance of the Fourth-Round Candidates . . . | 4 | | 2.2. | Evaluation Criteria
. | 4 | | 2.2.1. Security

CIS Safeguard 3.7 · Establish and Maintain a Data Classification Scheme Establish and maintain an overall data classification scheme for the enterprise. Enterprises may use labels, such as ·Sensitive·, ·Confidential· and ·Public·, and classify their data according to those labels. Review and update the classification scheme annually, or when significant enterprise changes occur that could impact this Safeguard. Implementation Groups: 2,3 Asset Type: data Security Function: identify Parent Control: Data Protection

(ii) Provide copies of any such communication to the agency and to other participating parties when they become known. However, if the protester has identified controlled unclassified information and requests a protective order, then the contracting officer shall obtain a redacted version from the protester to furnish to other interested parties, if one has not already been provided. * * * *

* PART 42·CONTRACT ADMINISTRATION AND AUDIT SERVICES 42.302 [Amended] 35. Amend section 42.302 by removing from paragraph (a)(21) the phrase ·Subpart 4.4· and adding ·4.402· in its place. PART 52·SOLICITATION PROVISIONS AND CONTRACT CLAUSES 36. Amend section 52.204-2 by revising the section heading, the introductory text, the clause heading, and the date of the clause to read as follows: 52.204-2 Security Requirements for Classified Information. As prescribed in 4.402-3(a), insert the following clause: Security Requirements for Classified Information (DATE) * * * * * 37. Amend section 52.204-9 by: a. Revising the date of the clause; b. Removing from paragraph (a) the phrase ·(FIPS PUB) Number· and adding ·(FIPS)· in its place; and c. Removing from paragraph (d) the phrase ·Federally-controlled information· and adding ·Federal information· in its place. The revision reads as follows: 52.204-9 Personal Identity Verification of Contractor Personnel. * * * * * Personal Identity Verification of Contractor Personnel (DATE) * * * * * 38. Amend section 52.204-16 by: a. Revising the date of the clause; and b. Removing from paragraph (g) the phrase ·Security Requirements· and adding ·Security Requirements for Classified Information· in its place. The revision reads as follows: 52.204-16 Commercial and Government Entity Code Reporting. * * * * * Commercial and Government Entity Code Reporting (DATE) * * * * * 39. Amend section 52.204-18 by: a. Revising the date of the clause; and b. Removing from paragraph (f) the phrase ·Security Requirements· and adding ·Security Requirements for Classified Information· in its place. The revision reads as follows: 52.204-18 Commercial and Government Entity Code Maintenance. * * * * * Commercial and Government Entity Code Maintenance (DATE) * * * * * 40. Amend section 52.204-21 by: a. Revising the introductory text and date of the clause; b. In paragraph (a): i. Revising the definition of ·Covered contractor information system·; ii. Adding in alphabetical order the definition for ·Covered Federal information·; iii. Removing the

definition for ·Federal contract information·; iv. Revising the definition of ·Information·; c. Removing from paragraph (b)(1)(vii) the phrase ·Federal Contract Information· and adding ·covered Federal information· in its place. d. Removing from paragraph (b)(2) the phrase ·controlled unclassified information (CUI)· and adding ·CUI· in its place; e. Adding paragraph (b)(3); and f. Removing from paragraph (c) the phrase ·Federal contract information· and adding ·covered Federal information· in its place. The revisions and additions read as follows: 52.204-21

(d) Privacy Act Statements. (1) When an individual is requested to furnish personal information about himself or herself for inclusion in a system of records, a Privacy Act Statement is required regardless of the medium used to collect the information (forms, personal interviews, telephonic interviews, or other methods). The Privacy Act Statement consists of the elements set forth in paragraph (d)(2) of this section. The statement enables the individual to make an informed decision whether to provide the information requested. If the personal information solicited is not to be incorporated into a system of records, the statement need not be given. However, personal information obtained without a Privacy Act Statement shall not be incorporated into any system of records. When soliciting SSNs for any purpose, see paragraph (b)(2) of this section. (2) The Privacy Act Statement shall include: (i) The Federal statute or Executive Order that authorizes collection of the requested information (See § 310.10(d)). (ii) The principal purpose or purposes for which the information is to be used; (iii) The routine uses that will be made of the information (See § 310.22(d)); (iv) Whether providing the information is voluntary or mandatory (See paragraph (e) of this section); and (v) The effects on the individual if he or she chooses not to provide the requested information. (3) The Privacy Act Statement shall be concise, current, and easily understood. (4) The Privacy Act statement may appear as a public notice (sign or poster), conspicuously displayed in the area where the information is collected, such as at check-cashing facilities or identification photograph facilities (but see § 310.16(a)). (5) The individual normally is not required to sign the Privacy Act Statement. (6) The individual shall be provided a written copy of the Privacy Act Statement upon request. This must be done regardless of the method chosen to furnish the initial advisement. (e) Mandatory as opposed to voluntary disclosures. Include in the Privacy Act Statement specifically whether furnishing the requested personal data is mandatory or voluntary. A requirement to furnish personal data is mandatory only when the DoD Component is authorized to impose a penalty on the individual for failure to provide the requested information. If a penalty cannot be imposed, disclosing the information is always voluntary. § 310.16 Forms. (a) DoD Forms. (1) DoD Instruction 7750.7 [8] provides guidance for preparing Privacy Act Statements for use with forms (see also paragraph (b) of this section). (2) When forms are used to collect personal information, the Privacy Act Statement shall appear as follows (listed in the order of preference): (i) In the body of the form, preferably just below the title so that the reader will be advised of the contents of the statement before he or she begins to complete the form; (ii) On the reverse side of the form with an appropriate annotation under the title giving its location;

DFARS clause 252.204-7002 is included in solicitations and contracts when the value of a NSP contract line or subline item is included in the price of another contract line or subline item, and it is necessary to withhold payment (printed page 58363) on the priced contract line or subline item until the related NSP item has been delivered. The clause prohibits contractors from billing the Government for a priced item that contains the value of a NSP item until the related NSP items have also been delivered to and accepted by the Government. While use of the clause is discretionary, it is beneficial to DoD in situations when NSP items are individual deliverables on a contract, even though the NSP items are a part or component of a priced item on another contract line or subline item. Currently, the clause text can be read as prohibiting the contractor from billing for any portion of a contract line or subline item that is associated with an NSP item until all of the NSP items have also been delivered to and accepted by the Government. It is not the intent of the Government to prohibit any and all payment on such contract line or subline items until all deliveries have been made and accepted for both the priced and NSP items. This rule simplifies the clause text to clarify that a contractor can bill the Government for the individual unit price of a delivered item, once the NSP item associated with the individually priced item has also been delivered and accepted by the Government. The rule also conforms the text of the clause to the current contract line item structure terminology by replacing ·contract line item· with ·contract line or subline item· and adds a prescription for the DFARS clause in the applicable section of DFARS 204.71. The modification of this DFARS text implements a recommendation from the DoD Regulatory Reform Task Force. On February 24, 2017, the President signed Executive Order (E.O.)

13777, ·Enforcing the Regulatory Reform Agenda,· which established a Federal policy ·to alleviate unnecessary regulatory burdens· on the American people. In accordance with E.O. 13777 , DoD established a Regulatory Reform Task Force to review and validate DoD regulations, including the DFARS. A public notice of the establishment of the DFARS Subgroup to the DoD Regulatory Reform Task Force, for the purpose of reviewing DFARS provisions and clauses, was published in the Federal Register at 82 FR 35741 on August 1, 2017, and requested public input. No public comments were received on these clauses. Subsequently, the DoD Task Force reviewed the requirements of DFARS clause 252.204-7002 and determined that the clause should be revised. III. Applicability to Contracts at or Below the Simplified Acquisition Threshold and for Commercial Items, Including Commercially Available Off-the-Shelf Items

means a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information (44 U.S.C. 3502(8)). Lawful Government purpose means any activity, mission, function, operation, or endeavor that the Government authorizes or recognizes as within the scope of its legal authorities or the legal authorities of non-executive branch entities such as state and local law enforcement. Limited dissemination control means any control identified on the CUI Registry that agencies may use to limit or specify CUI dissemination. On behalf of an agency means a Contractor uses or operates an information system or maintains or collects information for the purpose of processing, storing, or transmitting Federal information, and those activities (printed page 4298) are not incidental to providing a service or product to the Government. (c) Identifying and reporting information the Contractor believes or has reason to know is potentially CUI. (1) The Contractor shall notify the Contracting Officer within 8 hours of discovery if· (i) The Contractor discovers any information that the Contractor believes is CUI that is not identified in the SF XXX or is not marked or properly marked as required in the SF XXX; or (ii) There is any inconsistency between this clause and an SF XXX incorporated into the contract. (2) The Contractor shall take action to appropriately safeguard any information the Contractor believes is CUI that is not identified in the SF XXX or is not marked or properly marked as required in the SF XXX until a Contracting Officer makes a determination. (3) If the Contractor discovers any information that the contractor believes is CUI that is not identified in the SF XXX that is involved in a suspected or confirmed CUI incident, the Contractor shall notify the Contracting Officer and comply with paragraph (g) of this clause. (4) The Contractor is not entitled to use Government-provided information for its own purposes, whether or not the information is marked as CUI, unless the information is in the public domain, or unless the information was lawfully made available to the Contractor by someone other than the Government. (5) The Contractor shall appropriately identify information the Contractor owns and provides to the Government (e.g., contractor bid or proposal information, contractor-attributational information, or contractor proprietary business information). The Government will determine in accordance with agency procedures whether the information provided by the Contractor is CUI or entitled to other protections (e.g., contractor-attributational information associated with a CUI incident). (d) Safeguarding CUI. (1) The Contractor shall safeguard CUI that the Government identifies in the SF XXX and ensure handling consistent with 32 CFR 2002.14 .

Some commenters expressed concern that CMMC implementation would result in increased litigation by DIB companies or pursuit of False Claims Act penalties by DoD against DIB companies. One commenter erroneously believed that Mexico would participate in oversight of the CMMC ecosystem, and that ·a flood of litigation· may result from DIB companies losing contracts due to non-compliance with CMMC requirements. One commenter suggested that DoD should absolve contractors from False Claims Act prosecution when differences are found between C3PAO assessment results and a previously submitted contractor self-assessment, due to potentially valid reasons for the differing outcomes. Another suggested that DoD establish protections from regulatory and legal liability related to cyber incidents when the affected contractor has complied with relevant CMMC Program requirements. Response: The DoD lacks the authority to change the False Claims Act, which is a Federal law that imposes liability persons and companies who defraud or knowingly submit false claims to the government. Comments related to Safe Harbor provisions are outside the scope of this rule. Comments about potential industry litigation are also beyond the scope of the final rule and the recommendations provided were not appropriate for inclusion in this rule. Nothing in the rule prevents frivolous private lawsuits, but the rule does provide that the CMMC AB maintain an appeals process. The DoD has faithfully followed the formal rulemaking process, to include completion of the public comment period. Implementation of the CMMC program will be carried out objectively and in accordance with the tenets of the (printed page 83110) final rule. No foreign actors have any

role in DoD's administration of the program. 6. DoD Metrics Comment: Several commenters inquired about the types of metrics the DoD plans to use to monitor progress toward the DIB cybersecurity objectives that the CMMC program was designed to meet. One asked whether DoD's metrics would include testing, and another recommended they capture changes in the population of DoD contractors caused by cost impacts of CMMC implementation. Others referenced a December 2021 GAO Report that critiqued DoD's earlier attempts to implement the CMMC program. Specifically, they cited the GAO's finding that, at that time, DoD had not defined how it would analyze data to measure performance. A comment recommended the DoD identify responses to other GAO findings, which dealt with improvements to communications with industry and metrics for program management. Another comment asked whether management alignment within OSD, budget, and staffing of the CMMC program office are adequate.

Purpose The purpose of the Assess step is to determine if the controls selected for implementation are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security and privacy requirements for the system and the organization. NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

CHAPTER THREE PAGE 62 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-37r2>

ASSESSOR SELECTION TASK A-1 Select the appropriate assessor or assessment team for the type of control assessment to be conducted. Potential Inputs: Security, privacy, and SCRM plans; program management control information; common control documentation; organizational security and privacy program plans; SCRM strategy; system design documentation; enterprise, security, and privacy architecture information; security, privacy, and SCRM policies and procedures applicable to the system. Expected Outputs: Selection of assessor or assessment team responsible for conducting the control assessment. Primary Responsibility: Authorizing Official or Authorizing Official Designated Representative. Supporting Roles: Chief Information Officer; Senior Agency Information Security Officer; Senior Agency Official for Privacy. System Development Life Cycle Phase: New · Development/Acquisition; Implementation/Assessment. Existing · Operations/Maintenance. Discussion: Organizations consider both the technical expertise and level of independence⁸⁷ required in selecting control assessors.⁸⁸ Organizations ensure that control assessors possess the required skills and technical expertise to develop effective assessment plans and to conduct assessments of program management, system-specific, hybrid, and common controls, as appropriate. This includes general knowledge of risk management concepts and approaches as well as comprehensive knowledge of and experience with the hardware, software, and firmware components implemented. In organizations where the assessment capability is centrally managed, the senior agency information security officer may have the responsibility of selecting and managing the security control assessors or assessment teams for organizational systems. As controls may be implemented to achieve security and privacy objectives, organizations consider the degree of collaboration between security control and privacy control assessors that is necessary. Organizations can conduct self-assessments of controls or obtain the services of an independent control assessor. An independent assessor is an individual or group that can conduct an impartial assessment. Impartiality means that assessors are free from perceived or actual conflicts of interest with respect to the determination of control effectiveness or the development, operation, or management of the system, common controls, or program management controls. The authorizing official determines the level of assessor independence based on applicable laws, executive orders, directives, regulations, policies, or standards. The authorizing official consults with the Office of the Inspector General, chief information officer, senior agency official for privacy, and senior agency information security officer to help guide and inform decisions regarding assessor independence. The system privacy officer is responsible for identifying assessment methodologies and metrics to determine if privacy controls are implemented correctly, operating as intended, and sufficient to ensure compliance with applicable privacy requirements and manage privacy risks. The senior agency official for privacy is responsible for conducting assessments of privacy controls and documenting the results of the assessments. At the discretion of the organization, privacy controls may be assessed by an independent assessor. However, in all cases, the senior agency official for privacy is responsible and accountable for

⁸⁷ In accordance with [OMB A-130], an independent evaluation of privacy program and practices is not required. However, an organization may choose to employ independent privacy assessments at the organization's discretion. ⁸⁸ Some organizations may select control assessors prior to the RMF Assess step to support control assessments at the earliest opportunity during the system life cycle. Early identification and selection of assessors allows organizations to plan for the

assessment activities, including agreeing on the scope of the assessment. Organizations implementing a systems security engineering approach may also benefit from early selection of assessors to support verification and validation activities that occur throughout the system life cycle.

requires that a procurement policy, regulation, procedure or form (including an amendment or modification thereof) must be published for public comment if it relates to the expenditure of appropriated funds, and has either a significant effect beyond the internal operating procedures of the agency issuing the policy, regulation, procedure, or form, or has a significant cost or administrative impact on contractors or offerors. This final rule is not required to be published for public comment, because DoD is not issuing a new regulation; rather, this rule is merely removing an unnecessary provision from the DFARS. V. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804. VI. Executive Order 13771 This rule is not subject to E.O. 13771, because this rule is not a significant regulatory action under E.O. 12866. VI. Regulatory Flexibility Act Because a notice of proposed rulemaking and an opportunity for public comment are not required to be given for this rule under 41 U.S.C. (printed page 58332) 1707(a)(1) (see section IV. of this preamble), the analytical requirements of the Regulatory Flexibility Act (5 U.S.C. 601 et seq.) are not applicable. Accordingly, no regulatory flexibility analysis is required, and none has been prepared. VII. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). List of Subjects in 48 CFR Parts 204, 209, 212, and 252 Government procurement Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204, 209, 212, and 252 are amended as follows: 1. The authority citation for 48 CFR parts 204, 209, 212, and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1. PART 204-ADMINISTRATIVE AND INFORMATION MATTERS 204.7403 [Amended] 2. Amend section 204.7403 by: a. In the section heading, removing 'Solicitation provision and contract' and adding 'Contract' in its place; b. Removing paragraph (a); and c. Redesignating paragraphs (b) and (c) as paragraphs (a) and (b), respectively. PART 209-CONTRACTOR QUALIFICATIONS 3. Revise section 209.505-4(b)(ii) to read as follows: 209.505-4 Obtaining access to proprietary information. (b) ***

means prevention of damage to, protection of, and restoration of computers, electronic communications systems, electronic communications services, wire communication, and electronic communication, including information contained therein, to ensure its availability, integrity, authentication, confidentiality, and nonrepudiation. Cyber incident means actions taken through the use of computer networks that result in an actual or potentially adverse effect on an information system or the information residing therein. Declassification means a date or event which coincides with the lapse of the information's national security sensitivity, as determined by the OCA. Declassification occurs when the OCA has determined that the classified information no longer requires, in the interest of national security, any degree of protection against unauthorized disclosure, and the information has had its classification designation removed or cancelled. Defense articles means those articles, services, and related technical data, including software, in tangible or intangible form, which are listed on the United States Munitions List (USML) of the International Traffic in Arms Regulations (ITAR), as modified or amended. Defense articles exempt from the scope of ITAR section 126.17 are identified in Supplement No. 1 to Part 126 of the ITAR. Defense services means: (1) Furnishing assistance (including training) to foreign persons, whether in the United States or abroad, in the design, development, engineering, manufacture, production, assembly, testing, repair, maintenance, modification, operation, demilitarization, destruction, processing or use of defense articles; (2) Furnishing to foreign persons any controlled technical data, whether in the United States or abroad; or (3) Providing military training of foreign units and forces, regular and irregular, including formal or informal instruction of foreign persons in the United States or abroad or by correspondence courses, technical, educational, or information publications and media of all kinds, training aid, orientation, training exercise, and military advice. Derivative classification means the incorporating, paraphrasing, restating, or generating

in new form information that is already classified, and marking the newly developed material consistent with the classification markings that apply to the source information. Derivative classification includes classifying information based on classification guidance. Duplicating or reproducing existing classified information is not derivative classification. Document means any recorded information, regardless of the nature of the medium, or the method or circumstances of recording. Downgrade means a determination by a declassification authority that information classified and safeguarded at a specified level will be classified and safeguarded at a lower level. Embedded system

9. Implementation Schedule. This Standard became effective on May 26, 2002. 10. Patents. Implementations of the algorithm specified in this Standard may be covered by U.S. and foreign patents. 11. Export Control. Certain cryptographic devices and technical data regarding them are subject to federal export controls. Exports of cryptographic modules implementing this Standard and technical data regarding them must comply with all federal laws and regulations and must be licensed by the Bureau of Industry and Security of the U.S. Department of Commerce. Information about export regulations is available at <https://www.bis.doc.gov>. 12. Qualifications. NIST will continue to follow developments in the analysis of the AES algorithm. As with its other cryptographic algorithm standards, NIST will formally reevaluate this Standard every five years. In 1997, NIST initiated the Advanced Encryption Standard (AES) development effort [1] and called for the public to submit candidate algorithms for block ciphers. Block ciphers are the foundation for many cryptographic services, especially those that provide assurance of the confidentiality of data. In 2000, NIST announced the selection of Rijndael [2, 3] for the AES. - [1] James Nechvatal, Elaine Barker, Lawrence Bassham, William Burr, Morris Dworkin, James Foti, and Edward Roback. Report on the Development of the Advanced Encryption Standard (AES). Journal of Research of NIST (NIST JRES) , May 2001. <https://doi.org/10.6028/jres.106.023>. - [2] Joan Daemen and Vincent Rijmen. AES Proposal: Rijndael Document Version 2. AES Algorithm Submission, September 1999. Available at <https://csrc.nist.gov/csrc/media/projects/cryptographic-standards-and-guidelines/documents/aes-development/rijndael-ammended.pdf>. - [3] Joan Daemen and Vincent Rijmen. The Design of Rijndael - The Advanced Encryption Standard (AES), Second Edition . Information Security and Cryptography. Springer, 2020. <https://doi.org/10.1007/978-3-662-60769-5>.

n. Whether the Department should specify how much time regulated entities have to implement encryption for technology assets that do not support encryption. If so, please explain. o. Whether the Department should provide more detailed requirements for network segmentation, such as the type(s) of technologies that should be segmented and how to determine whether certain technologies should be segmented. If so, please explain. p. Whether the exceptions the Department has proposed to the implementation specification for MFA are appropriate. If not, please explain. q. Whether the Department should provide additional exceptions to the implementation specification for MFA. If so, please explain. r. Whether the Department should require a regulated entity to review its compensating controls adopted to comply with the exceptions to the implementation specification for MFA more frequently than once every 12 months. s. The costs and burdens for regulated entities to implement MFA. t. Whether the Department should require regulated entities to deploy an endpoint detection and response (EDR), security information and event management (SIEM), or other specific solution. u. Whether once every six months is the appropriate frequency for the automated vulnerability scans required under the implementation specification for vulnerability management. If not, please explain. v. Whether the Department should define in regulation or guidance what constitutes an authoritative source of known vulnerabilities. If so, please explain. w. Whether once every 12 months is the appropriate frequency for the penetration testing required under the implementation specification for vulnerability management. If not, please explain. x. For regulated entities that have conducted penetration tests, the amount of time and costs of such tests. G. Section 164.314-Organizational Requirements 1. Section 164.314(a)(1)-Standard: Business Associate Contracts or Other Arrangements a. Current Provisions The first standard in 45 CFR 164.314 contains the requirements for business associate agreements and other arrangements. The associated implementation specifications at 45 CFR 164.314(a)(2) require that a business associate agreement include provisions compelling a business associate to do all of the following: (1) comply with the requirements of the Security Rule; [818] (2) ensure that any subcontractors that create, receive, maintain, or transmit ePHI on behalf of the business associate agree to comply with the applicable requirements of the Security Rule by also entering into a business associate agreement; [819] and (3) report to the covered entity any security incident of which it becomes aware, including breaches of unsecured PHI as required by the Breach Notification Rule. [820] Under

Finally, the changes to the costs and benefits of the final rule due to the expanded coverage to include persons that export food for consumption outside of the United States are estimated to be small. We assume that the export of food and feed occurs at the manufacturing and wholesaling levels, with retailers unlikely to engage in export. The U.S. Census Bureau's 1997 Economic Census (Ref.17) indicates that approximately 4 percent of wholesale trade in all grocery and related products (NAICS code 4224) was from export sales. We assume that the same percent also applies to exports in the manufacturing sector and also to the numbers of facilities in those sectors. An estimate of 4 percent likely overstates the true incremental cost of covering exported food and feed since most, if not all of the establishments engaged in export are also likely to be engaged in domestic commerce and consequently would not incur additional learning and records redesign costs. Moreover, firms that export and also engage in domestic commerce are unlikely to incur additional maintenance costs because it is unlikely that they would follow two sets of recordkeeping practices. Consequently, only firms that are exclusively exporters will incur incremental recordkeeping costs as a result of expanded coverage. We assume that half of all wholesale and manufacturing establishments estimated to engage in export, or 2,736 facilities, are exclusively exporters and will incur recordkeeping costs as a result of expanded coverage to include export of food and feed. The incremental benefits from expanding the coverage to include exported food and feed are from the possibility that some of these shipments may be diverted for domestic consumption, and their coverage may enhance traceback investigations should they be necessary. The food safety (but not food security) benefits from expanded coverage are likely to be negligible since the likelihood of diversion is small, and the likelihood that a diverted shipment is accidentally contaminated is also small. However, the food security benefits, while not quantifiable, include classified scenarios that could include diversion of food and feed. Further, FDA is concerned that exempting foods intended for export from the recordkeeping regulations could lead to such foods being targeted for tampering by terrorists and reintroduction into domestic commerce as they would prove more intractable to tracing investigations. Including the revisions described previously, we estimate that a total of 707,672 facilities will be covered by this final rule. This represents a reduction of 96,642 facilities compared with the number estimated in the analysis of the proposed rule. 2.

High Cost of Tracking by Lot Code

DoD considered many alternatives before deciding upon the current CMMC structure. The DoD has established requirements for a CMMC Accreditation Body, and this accreditation body will administer the CMMC Ecosystem. The appeals process is defined in §§ 170.8(b)(16) and 170.9(b)(9), (14), (20), and (21). The DoD will not assume the workload of directly managing the CMMC ecosystem or the other alternatives suggested. DoD must treat all potential defense contractors and subcontractors fairly. DoD cannot inadvertently create a pathway to a free assessment for an organization by virtue of its dual-purpose as a C3PAO and separately as a defense contractor. Therefore, DoD assesses C3PAOs free of charge, but the assessment does not result in a Certificate of CMMC Status. The C3PAOs determine the people, processes, and technologies that are in-scope for their DIBCAC assessment to become a C3PAO. The need to protect the assessment information is independent of its status as FCI or CUI. Assessment information, such as which requirements are MET or not, as well as the evidence and analysis leading to that result, would provide valuable insights to an adversary if not protected. A C3PAO is not a CSP and therefore would not require a FedRAMP moderate assessment to be a C3PAO. However, if they use a CSP to process, store, or transmit assessment information, then the CSP would require a FedRAMP Moderate, or equivalent, assessment. The CSP assessment results and CRM would be in scope for the C3PAO assessment. The requirements in § 170.9 apply to both authorized and accredited C3PAOs. The only difference between authorization and accreditation is the status of the CMMC Accreditation Body. Prior to the CMMC AB achieving its full ISO/IEC 17011:2017(E) compliance, the interim term "authorized" is used for C3PAOs. As stated in §§ 170.8(b)(3)(i) and 170.9(b)(1) and (2), currently authorized C3PAOs must achieve and maintain compliance with ISO/IEC 17020:2012(E) within 27 months of authorization. As stated in § 170.9(b)(6), C3PAOs must obtain a Level 2 certification assessment, but this does not result in a CMMC Level 2 certificate. The DoD declines to modify the rule text related to C3PAO requirements as it does not make a substantive change. Requirements are specified in the rule for each entity within the CMMC ecosystem. A C3PAO may start preparing for compliance with ISO/IEC 17020:2012(E) before the Accreditation Body achieves compliance with ISO/IEC 17011:2017(E). The 27-month timeline for a C3PAO to achieve and maintain compliance with ISO/IEC 17020:2012(E) begins on the date that the C3PAO is authorized by the Accreditation Body, as addressed in § 170.9(b)(2) C3PAOs authorized by the CMMC AB prior to becoming

compliant with ISO/IEC 17020:2012(E) must be accredited by the CMMC AB within 27 months of the C3PAO's initial authorization to meet CMMC program requirements. The accreditation process is not tied to, nor is it impacted by, the DoD's appropriations period.

Level 2 (Self) is a self-assessment to secure CUI processed, stored, or transmitted in the course of fulfilling the contract. The OSA must comply with the 110 Level 2 security requirements derived from NIST SP 800-171 R2. Level 2 (C3PAO) differs from Level 2 (Self) in the method of verifying compliance. OSAs must hire a C3PAO to conduct an assessment of the OSA's compliance with the 110 security requirements of NIST SP 800-171 R2. OSAs can shop for C3PAOs on the CMMC Accreditation Body (AB) Marketplace. Level 3 (DIBCAC) is a government assessment of 24 additional requirements derived from NIST SP 800-172, titled "Enhanced Security Requirements for Protecting Controlled Unclassified Information: A Supplement to NIST Special Publication 800-171," February 2021 (NIST SP 800-172 Feb2021). The OSA must ensure that they have already achieved a CMMC Status of Final Level 2 (C3PAO) before seeking CMMC Status of Final Level 3 (DIBCAC). Once this is done, an OSA should then initiate a Level 3 certification assessment by emailing a request to Defense Contract Management Agency (DCMA) Defense Industrial Base Cybersecurity Assessment Center (DIBCAC) point of contact found at www.dcma.mil/DIBCAC, being sure to include the Level 2 (C3PAO) certification unique identifier in the email. Scoping In order to achieve a specified CMMC Status, OSAs must first identify which information systems, including systems or services provided by External Service Providers (ESPs), will process, store, or transmit FCI, for Level 1 (Self), and CUI for all other CMMC Statuses. These information systems constitute the scope of the assessment. Within these information systems, for Level 2 and Level 3 the assets should be further broken down into asset categories: Contractor Risk Managed Assets (Level 2), Security Protection Assets (Level 2 and 3), and Specialized Assets (Level 2 and 3). For Level 1 all assets, with the exclusion of Specialized Assets, are simply identified as either in-scope or out-of-scope based on whether they process, store, or transmit FCI. Definitions and treatment of these categories as they relate to assessment scoping, treatment of ESPs, and treatment of assets which cannot be secured due to their inherent design, can be found at §170.19. Assessment and Affirmation a. OSAs that meet all 15 Level 1 requirements have achieved CMMC Status of Final Level 1 (Self). The OSA (printed page 83096) must submit an affirmation of compliance with FAR clause 52.204-21 requirements in SPRS. At this point, OSAs have satisfied the CMMC requirements needed for award of contracts requiring a CMMC Status of Final Level 1 (Self). To maintain a CMMC Status of Final Level 1 (Self), this entire process must be repeated in full on an annual basis, including both self-assessment and affirmation.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Health and Human Services Food and Drug Administration [Docket No. FDA-2011-D-0916] AGENCY: Food and Drug Administration, HHS. ACTION: Notice. SUMMARY: The Food and Drug Administration (FDA) is announcing the availability of the guidance entitled "Medical Device Classification Product Codes." This document describes how device product codes are used in a variety of FDA program areas to regulate and track medical devices regulated by the Center for Devices and Radiological Health (CDRH) and the Center for Biologics Evaluation and Research (CBER). DATES: Submit either electronic or written comments on this guidance at any time. General comments on Agency guidance documents are welcome at any time. ADDRESSES: Submit written requests for single copies of the guidance document entitled "Medical Device Classification Product Codes" to the Division of Small Manufacturers, International, and Consumer Assistance, Center for Devices and Radiological Health, Food and Drug Administration, 10903 New Hampshire Ave., Bldg. 66, Rm. 4613, Silver Spring, MD 20993-0002 or the Office of Communication, Outreach and Development (HFM-40), 1401 Rockville Pike, suite 200N, Rockville, MD 20852. Send one self-addressed adhesive label to assist that office in processing your request, or fax your request to CDRH at 301-847-8149. See the SUPPLEMENTARY INFORMATION section for information on electronic access to the guidance. Submit electronic comments on the guidance to <http://www.regulations.gov>. Submit written comments to the Division of Dockets Management (HFA-305), Food and Drug Administration, 5630 Fishers Lane, Rm. 1061, Rockville, MD 20852. Identify comments with the docket number found in brackets in the heading of this document. FOR FURTHER INFORMATION CONTACT: Diane Garcia, Center for Devices and Radiological Health, Food and Drug Administration, 10903 New Hampshire Ave., Bldg. 66, Rm. 1644, Silver Spring, MD 20993-0002, 301-796-6559; or Stephen Ripley, Center for Biologics Evaluation and Research

(HFM-17), Food and Drug Administration, 1401 Rockville Pike, suite 200N, Rockville, MD 20852, 301-827-6210. SUPPLEMENTARY INFORMATION: I. Background Since the May 28, 1976, Medical Device Amendments were passed, the Classification Regulation Panels (parts 862 through 892 (21 CFR parts 862 through 892

Offerors will also need to be familiar with these requirements before submitting a proposal to provide such services. For each of the 84 contractors that receive a contract annually for these services, the Government estimates that, on average, two other offerors, or a total of 168 offerors (84 contractor awards * 2 unsuccessful offerors) will familiarize themselves with the clause requirements, submit a proposal, but will not receive a contract award. As a result, it is expected that all 252 (84 contractors + 168 offerors) of these contractors and offerors will be required to become familiar with the various compliance requirements of the rule. It is estimated that it will take each offeror or contractor eight hours, on average, to review the rule and gain a basic understanding these new requirements. The average wage rate of a contractor employee is estimated to be \$57.28 per hour, which is the average of the mean wages reported by the Bureau of Labor Statistics (BLS) for various occupational categories that design, analyze, maintain, and oversee information systems for an organization. A factor of 42 percent, based on the BLS Employer Costs for Employee Compensation Summary dated March 17, 2023 (<https://www.bls.gov/news.release/ecec.nr0.htm>), is applied to the average wage rate to account for total employee benefits paid for by the employer ($\$57.28 * 1.42 = \81.34), and a factor of 12 percent is then applied to the rate of \$81.34 to account for employer overhead, which results in a loaded rate of \$91.10 ($\$81.34 * 1.12$) for FIS occupations. Therefore, the estimated cost for 252 contractors and offerors to familiarize themselves with the rule in year one is approximately \$183,700 (252 contractors and offerors * 8 hours/entity * \$91.10/hour). The cost accounts for the time needed to comprehend the text of the rule, as well as locate and generally review the requirements within each of the cited documents in the rule.

2. Compliance With NIST Guidelines

All 28 contractors that develop, implement, operate, or maintain a FIS using non-cloud computing services are required by paragraphs (e) and (f) of the new clause 52.239-YY to use or apply various NIST SP guidelines for managing risk, security, and privacy, as applicable. The extent to which each of these guidance documents needs to be implemented by a contractor depends (printed page 68407) on many variables, including: the extent to which the guidance is already implemented in the contractor's existing practices; the scope and requirements of each contract; the knowledge and expertise of the contractor's employees; the manner in which a contractor chooses to implement a requirement; and the resources and tools available to the contractor in performing the contract.

(2) Do not claim specifically an exemption under section 552a(k)(1) of the Privacy Act for any system of records. The blanket exemption affords protection to all classified material in all system of records maintained. (d) Provisions from which exemptions may be claimed. The Head of a DoD Component may claim an exemption from any provision of the Act from which an exemption is allowed (see Appendix D). (e) Use of exemptions. (1) Use exemptions only for the specific purposes set forth in the exemption rules (see paragraph (b) of § 310.31). (2) Use exemptions only when they are in the best interest of the Government and limit them to the specific portions of the records requiring protection. (3) Do not use an exemption to deny an individual access to any record to which he or she would have access under 32 CFR part 286 . (f) Exempt records in non-exempt systems. (1) Exempt records temporarily in the custody of another Component are considered the property of the originating Component. Access to these records is controlled by the system (printed page 18775) notices and rules of the originating Component. (2) Exempt records that have been incorporated into a nonexempt system of records are still exempt but only to the extent to which the provisions of the Act for which an exemption has been claimed are identified and an exemption claimed for the system of records from which the record is obtained and only when the purposes underlying the exemption for the record are still valid and necessary to protect the contents of the record. (3) If a record is accidentally misfiled into a system of records, the system notice and rules for the system in which it should actually be filed shall govern. § 310.27

Access exemption. (a) An individual is not entitled to access information that is compiled in reasonable anticipation of a civil action or proceeding. (b) The term 'civil action or proceeding' is intended to include court proceedings, preliminary judicial steps, and quasi-judicial administrative hearings or proceedings (i.e., adversarial proceedings that are subject to rules of evidence). (c) Any information prepared in anticipation of such actions or proceedings, to include information prepared to advise the DoD Component officials of the possible legal or other consequences of a given course of action, is protected. (d) The exemption is similar to the

attorney work-product privilege except that it applies even when the information is prepared by nonattorneys. (e) The exemption does not apply to information compiled in anticipation of criminal actions or proceedings. § 310.28 General exemption. (a) Use of specific exemptions. A DoD Component is not authorized to claim the exemption for records maintained by the Central Intelligence Agency established by 5 U.S.C. 552a(j)(1) of the Privacy Act. (b) The general exemption established by 5 U.S.C. 552a(j)(2) of the Privacy Act may be claimed to protect investigative records created and maintained by law-enforcement activities of a DoD Component.

means an administrative determination that an individual is eligible, from a security point of view, for access to classified information of the same or lower category as the level of the personnel clearance being granted. Prime contract means a contract awarded by a GCA to a contractor for a legitimate USG purpose. Prime contractor means the contractor who receives a prime contract from a GCA. Privileged user means a user that is authorized (and, therefore, trusted) to perform security-relevant functions that ordinary users are not authorized to perform. Proscribed information means: (1) TOP SECRET information; (2) COMSEC information or material, excluding controlled cryptographic items when unkeyed or utilized with unclassified keys. (3) RD; (4) SAP information; or. (5) SCI. Protective security service means a transportation protective service provided by a cleared commercial carrier qualified by DoD's Surface Deployment and Distribution Command to transport SECRET shipments. Q access authorization means an access determination that is granted by DOE or NRC based on a Tier 5 or successor background investigation as set forth in applicable national-level requirements and DOE directives. Within DOE and the NRC, a ·Q· access authorization permits an individual with an official ·need to know· to access Top Secret, Secret and Confidential Restricted Data, Formerly Restricted Data, Transclassified Foreign (printed page 83318) Nuclear Information, National Security Information, or special nuclear material in Category I or II quantities, as required in the performance of official duties. A ·Q· access authorization is required for individuals with a need to know outside of DOE, NRC, DoD, and in a limited case NASA, to access Top Secret and Secret Restricted Data. Remote terminal means a device communicating with an automated information system from a location that is not within the central computer facility. Restricted area means a controlled access area established to safeguard classified material that, because of its size or nature, cannot be adequately protected during working hours by the usual safeguards, but is capable of being stored during non-working hours in an approved repository or secured by other methods approved by the CSA. RD means all data concerning (1) design, manufacture, or utilization of atomic weapons; (2) the production of special nuclear material; or (3) the use of special nuclear material in the production of energy, but does not include data declassified or removed from the RD category pursuant to section 142 of the AEA. SAP means any program that is established to control access and distribution and to provide protection for particularly sensitive classified information beyond that normally required for TOP SECRET, SECRET, or CONFIDENTIAL information. A SAP can be created or continued only as authorized by a senior agency official delegated such authority pursuant to E.O. 13526 . Schedule 13D

g Critical Infrastructure Cybersecurity 19 referred to how few technical standards or best practices exist to mitigate the impact of cybersecurity activities on individual privacy and civil liberties. It is in the best interests of the USG to support the development and use of cybersecurity standards that minimize risks to privacy, promote information-sharing relating to cybersecurity, and allow the USG to combat cyber-enabled threats. Greater understanding of how to identify privacy risks and integrate mitigations into cybersecurity standards or their deployment in information systems will require further research.

putting the subject of an investigation, study, or analysis on notice of that fact, thereby permitting the subject to engage in conduct intended to frustrate or impede the activity. (G) From subsection (e)(4)(G), (e)(4)(H), and (e)(4)(I) (Agency Requirements) because portions of this system are exempt from the access and amendment provisions of subsection (d). (H) From subsection (e)(5) because the requirement that records be maintained with attention to accuracy, relevance, timeliness, and completeness could unfairly hamper law enforcement processes. It is the nature of law enforcement to uncover the commission of illegal acts at diverse stages. It is often impossible to determine initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further details are brought to light. (I) From subsection (e)(8) because the requirement to serve notice on an individual when a record is disclosed under compulsory legal process could unfairly hamper law enforcement processes. It is the nature of law enforcement that there are

instances where compliance with these provisions could alert the subject of an investigation of the fact and nature of the investigation, and/or the investigative interest of intelligence or law enforcement agencies; compromise sensitive information related to national security; interfere with the overall law enforcement process by leading to the destruction of evidence, improper influencing of witnesses, fabrication of testimony, and/or flight of the subject; reveal a sensitive investigative or intelligence technique; or constitute a potential danger to the health or safety of law enforcement personnel, confidential informants, and witnesses. (J) From subsection (f) because requiring the Agency to grant access to records and establishing agency rules for amendment of records would unfairly impede the agency's law enforcement mission. To require the confirmation or denial of the existence of a record pertaining to a requesting individual may in itself provide an answer to that individual relating to the existence of an on-going investigation. The investigation of possible unlawful activities would be jeopardized by agency rules requiring verification of the record, disclosure of the record to the subject, and record amendment procedures. (K) From subsection (g) to the extent that the system is exempt from other specific subsections of the Privacy Act. (27) System identifier and name. DMDC 24 DoD, Defense Information System for Security (DISS). (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (ii)

Section 170.4 includes acronyms and definitions used in the rule text and can be used as a reference while reading the text and tables. CMMC introduces new terms and associated definitions, and customizes definitions for existing terms, as applied to the CMMC Program. CMMC-custom terms and definitions are clearly marked to distinguish from terms sourced externally. CMMC also utilizes terms created by other authoritative sources, including NIST. Terms from other authoritative sources are also listed in § 170.4 and are properly sourced. The Department developed the following CMMC-custom terms to enhance understanding of the requirements and elements of the CMMC Program: Accreditation Accreditation Body Affirming Official Assessment Level 1 self-assessment Level 2 self-assessment Level 2 certification assessment Level 3 certification assessment POA&M closeout self-assessment POA&M closeout certification assessment Assessment Findings Report Assessment Team Asset Categories Authorized Cloud Service Provider CMMC Assessment and Certification Ecosystem CMMC Assessment Scope CMMC Assessor and Instructor Certification Organization (CAICO) CMMC instantiation of eMASS CMMC Status Final Level 1 (Self) Conditional Level 2 (Self) Final Level 2 (Self) Conditional Level 2 (C3PAO) Final Level 2 (C3PAO) Conditional Level 3 (DIBCAC) Final Level 3 (DIBCAC) CMMC Status Date CMMC Third-Party Assessment Organization (C3PAO) Contractor Risk Managed Assets Controlled Unclassified Information (CUI) Assets Enduring Exception External Service Provider (ESP) Operational plan of action Organization-defined Organization Seeking Assessment (OSA) Organization Seeking Certification (OSC) Out-of-Scope Assets Periodically Process, store, or transmit Restricted Information Systems Security Protection Assets Security Protection Data Specialized Assets Temporary Deficiency Test Equipment. Section 170.5-Policy Section 170.5 addresses the policy underlying the rule. The protection of FCI and CUI on defense contractor information systems is crucial to the continuity of the missions and functions of the DoD. To that end, this rule requires that contractors and subcontractors implement the specified security requirements for the applicable (printed page 83100) CMMC Level. For CMMC Level 3, the selected security requirements are defined in NIST SP 800-172 Feb2021 with the applicable DoD Organization-Defined Parameters (ODPs) defined in table 1 to § 170.14(c)(4). Program Managers and requiring activities identify the applicable CMMC Level and assessment type. Factors used to determine which CMMC Level and assessment type will be applied are included but not limited to the list found in § 170.5(b)(1-5). CMMC Program requirements will flow down to subcontractors, as applicable (see § 170.23). A DoD Service Acquisition Executive or a Component Acquisition Executive may elect to waive inclusion of CMMC Program requirements in a solicitation or contract.

According to Considerations for Identity Management in Public Safety Mobile Networks, Appendix C-Summary of Identity Proofing and Credential Issuance Requirements: | | In-person | A current biometric (e.g., photograph or fingerprints) is recorded to ensure that Applicant cannot repudiate application | A current biometric (e.g., photograph or fingerprints) is recorded to ensure that Applicant cannot repudiate application | A current biometric (e.g., photograph or fingerprints) is recorded to ensure that Applicant cannot repudiate application | A current biometric (e.g., photograph or fingerprints) is recorded to ensure that Applicant cannot repudiate application | |

Remote Not Admissible | Not applicable | Not applicable | Not applicable | Not applicable | | Remote
Not Admissible | Not applicable | Not applicable | Not applicable | Not applicable | | Remote Not
Admissible | Not applicable | Not applicable | Not applicable | Not applicable |

There are a total of 4,415 of such facilities listed in the County Business Pattern data. In the NES statistics, there are 4,700 reported for the aggregate NAICS code of 4931. To estimate the number of warehousing facilities that would be included in NAICS code 49311 in the NES statistics, we scaled the aggregate number in the NES statistics by the ratio of the numbers reported for code 49311 to the total of those reported under code 3931 in the County Business Pattern. When the imputed NES numbers for code 49311 are added to the reported County Business Pattern numbers for code 49311, the total number of facilities in the NAICS code is 7,328 facilities. We adjust the total number of warehouses by one half of the total number of facilities reported for code 49311 by assuming that half of the total number of facilities included in that code handle food items. The number of warehouse facilities is revised upward to 6,089 from the 2,425 in the PRIA. The facilities-to-firm adjustment factor used for the facilities listed in NAICS code 49311 is the average of that used for the (printed page 71634) other two warehouse codes in the analysis. (Comment 186) One comment requests clarification as to whether all members of the International Bottled Water Association were included in the number of facilities covered by the regulation. (Response) The NAICS code 3121 used in the PRIA includes all beverage manufacturers and specifically includes bottled water manufacturers. All other bottled water suppliers are included in the various NAICS codes used to count wholesalers and retailers, and other food suppliers.

e. Remediation Comment: Two respondents commented on the need to provide equitable adjustments, a means of remedy, and/or a pathway to reinstatement once a supplier is excluded. One of the respondents commented that while DFARS 239.7305 allows DoD to exclude sources, it does not provide a pathway to reinstatement or for inclusion once a supplier is excluded, proposing that DoD establish a separate rulemaking and coordinate a unified policy with an industry-Government working group to gain insight into how remediation and rejoining the defense industrial base can be accomplished in a responsible manner. This respondent further commented that DoD should provide equitable adjustments and other remedies for prime contractors whose subcontractors are excluded, stating that the new regulations fail to provide relief for prime contractors who must exclude a source through no fault of its own. Another respondent suggested that a periodic review of excluded contractors should be required for ongoing contracts with new task orders, adding that if a vendor has been excluded without notice, the interim rule should require the agency to review that decision on no less than an annual basis for as long as the contract is in place. This respondent also commented that the regulation should specifically afford remedies, including equitable adjustments, whenever the authority at DFARS 239.7305(c) is exercised and a prime must exclude a subcontractor. Response: Risk will be evaluated on case-by-case basis, and any exclusion will be for a particular source selection and not a blanket exclusion. Offerors are eligible to compete for future solicitations even after section 806 has excluded them from a particular source selection. Consistent with national security, i.e., with proper clearances and in a manner that will not put the warfighter, the system, or intelligence operations at risk, DoD will discuss risks to the trust of critical systems or components with its industrial base as well as potential remedies. This is particularly true in the system integration context where the program office and the prime contractors are more likely to have the time and clearances to develop tailored mitigations. Where appropriate, DoD will partner with its contractors to mitigate supply chain risk in lieu of executing section 806 authorities. In most cases, non-806 mitigations will sufficiently manage the risk; when that is not the case and exclusion of a source is required, DoD does not intend to provide equitable adjustments or other remedies. 6. Impact of Rule a. Economic/Cost Impact Comment:

3.4.3 | Kerberos Authentication... 3.4.3 Kerberos Authentication Kerberos (usually together with an LDAP-based directory, such as Active Directory) implements single sign-on within a Windows domain or Kerberos realm, and allows user accounts and credentials to be stored in a centralized directory.

(iv) For acquisitions that may require covered Federal information to reside in or transit through contractor information systems, discuss compliance with 4.404. (v) For acquisitions that may require a contractor to have access to, create, collect, use, process, store, maintain, disseminate, disclose, or dispose of CUI, discuss the security, marking, training, incident reporting, and other requirements (e.g., destruction) applicable to CUI (see 4.403-5 and 4.403-6). * * * * * 20.
Amend section 7.503 by revising paragraph (d)(11) to read as follows: 7.503 Policy. * * * * *

(d) * * * (11) Contractors working in any situation that permits or might permit them to gain access to controlled unclassified information (CUI). See 4.403. * * * * * PART 9-CONTRACTOR QUALIFICATIONS 9.505 [Amended] 21. Amend section 9.505 by removing from paragraph (b)(1) the phrase ·Proprietary information· and adding the phrase ·Contractor proprietary business information· in its place. 22. Amend section 9.505-4 by: a. Removing from paragraph (a) introductory text the phrase ·proprietary information from others· and adding ·another contractor's proprietary business information· in its place; and b. Revising paragraph (b). The revision reads as follows: 9.505-4 Obtaining access to proprietary information. * * * * * (b) A contractor that gains access to another contractor's proprietary business information in performing advisory and assistance services for the Government must agree with the other company to protect its information from unauthorized use or disclosure for as long as it remains proprietary and refrain from using the information for any purpose other than that for which it was furnished. The contracting officer shall obtain copies of these agreements and ensure that they are properly executed. * * * * * 9.508 [Amended] 23. Amend section 9.508 by removing from paragraph (h) introductory text and paragraph (h)(1) the phrase ·proprietary information· and adding ·contractor proprietary business information· in their places, respectively. * * * * * PART 11-DESCRIBING AGENCY NEEDS 24. Amend section 11.002 by adding paragraph (i) to read as follows: 11.002 Policy. * * * * * (i) When agencies acquire products and services subject to 32 CFR part 2002 , Controlled Unclassified Information (CUI) (see 4.403), the SF XXX, Controlled Unclassified Information (CUI) Requirements, must be incorporated in the contract and must identify, at a minimum: (1) The CUI the contractor will handle in performance of the contract; (printed page 4295) (2) Any CUI access and dissemination requirements placed on the contractor during performance of the contract; (3) Federal and non-Federal information systems the contractor will use to handle CUI in the performance of the contract; (4) System security and privacy requirements for each information system, as appropriate, and any additional security and privacy measures required by the agency; (5) Any instructions for handling CUI during performance of the contract;

Begins one calendar year following the start date of Phase 2. In addition to Phase 1 and 2 requirements, DoD intends to include CMMC Level 2 Certification Assessment for all applicable DoD solicitations and contracts as a condition of contract award and as a condition to exercise an option period on a contract awarded prior to the effective date. DoD intends to include CMMC Level 3 Certification Assessment for all applicable DoD solicitations and contracts as a condition of contract award. DoD may, at its discretion, delay the inclusion of CMMC Level 3 Certification Assessment to an option period instead of as a condition of contract award. (4) Phase 4, Full Implementation. Begins one calendar year following the start date of Phase 3. DoD will include CMMC Program requirements in all applicable DoD solicitations and contracts including option periods on contracts awarded prior to the beginning of Phase 4. §170.4 Acronyms and definitions. (a) Acronyms. Unless otherwise noted, these acronyms and their terms are for the purposes of this part. AC·Access Control APT·Advanced Persistent Threat APP·Approved Publisher Partner AT·Awareness and Training ATP·Approved Training Provider C3PAO·CMMC Third-Party Assessment Organization CA·Security Assessment CAICO·CMMC Assessors and Instructors Certification Organization CAGE·Commercial and Government Entity CCA·CMMC Certified Assessor CCP·CMMC Certified Professional CFR·Code of Federal Regulations CIO·Chief Information Officer CM·Configuration Management CMMC·Cybersecurity Maturity Model Certification CMMC PMO·CMMC Program Management Office CNC·Computerized Numerical Control CoPC·Code of Professional Conduct CSP·Cloud Service Provider CUI·Controlled Unclassified Information DCMA·Defense Contract Management Agency DD·Represents any two-character CMMC Domain acronym DFARS·Defense Federal Acquisition Regulation Supplement DIB·Defense Industrial Base DIBCAC·DCMA's Defense Industrial Base Cybersecurity Assessment Center DoD·Department of Defense DoDI·Department of Defense Instruction eMASS·Enterprise Mission Assurance Support Service ESP·External Service Provider FAR·Federal Acquisition Regulation FCI·Federal Contract Information FedRAMP·Federal Risk and Authorization Management Program GFE·Government Furnished Equipment IA·Identification and Authentication ICS·Industrial Control System IIoT·Industrial Internet of Things IoT·Internet of Things IR·Incident Response IS·Information System IEC·International Electrotechnical Commission ISO/IEC·International Organization for Standardization/International Electrotechnical Commission IT·Information Technology L#·CMMC Level Number MA·Maintenance MP·Media Protection MSP·Managed Service Provider MSSP·Managed Security Service Provider NARA·National Archives and Records Administration NAICS·North American Industry Classification System NIST·National Institute of Standards and Technology N/A·Not Applicable ODP·Organization-Defined Parameter OSA·Organization Seeking Assessment OSC·Organization Seeking Certification OT·Operational Technology

In addition to the procedures described above, requesters should reasonably identify the record, specify the information they are contesting, state the corrective action sought and the reasons for the correction, and provide information justifying why the record is not accurate, complete, timely, or relevant to an FDA purpose. Rules and procedures regarding amendment of Privacy Act records appear in 21 CFR part 21, subpart E . P. Record Source Categories Information in this system is obtained from the following sources: Directly from a commissioned individual or individual under consideration for commissioning; FDA employee; FDA contractor; sponsoring State, local or Federal agency; former sponsoring, employing or commissioning agency; other State, local or Federal agencies; contract employer; and the subject individual's former employer. Q. Records Exempted from Certain Provisions of the Privacy Act None. III. Comments Interested persons may submit either electronic comments regarding this document to <http://www.regulations.gov> or written comments to the Division of Dockets Management (see ADDRESSES). It is only necessary to send one set of comments. Identify comments with the docket number found in brackets in the (printed page 72690) heading of this document. Received comments may be seen in the Division of Dockets Management between 9 a.m. and 4 p.m., Monday through Friday, and will be posted to the docket at <http://www.regulations.gov> . Dated: December 1, 2014. Leslie Kux, Associate Commissioner for Policy. [FR Doc. 2014-28634 Filed 12-5-14; 8:45 am] BILLING CODE 4164-01-P

(Comment 146) Many foreign governments express concern that FDA does not have authority regarding recordkeeping and record access when a firm is located in a foreign country. One foreign government urges FDA to recognize the role of another competent authority with respect to records access as provided for under the World Trade Organization Agreement on Sanitary and Phytosanitary Measures. Foreign governments request that FDA operate under agreements with these governments so that FDA will convey its request to the competent authority in that country. The competent authority can then carry out investigations on behalf of FDA and provide FDA with any resulting relevant information. (Response) Foreign persons, except those who transport food in the United States, are not subject to these final recordkeeping regulations. If FDA needs to access food records that are established and maintained by foreign persons, FDA will work with the relevant competent authorities in those countries to do so. (Comment 147) One comment notes that the proposed rule does not take into account the time required to translate into English records in other languages that are obtained from firms located in foreign countries. (Response) Foreign persons, except those who transport food in the United States, are not subject to these final recordkeeping regulations. In the event FDA needs to access records kept by foreign persons, FDA intends to work (printed page 71607) with the relevant competent authorities in those countries to do so. (Comment 148) One comment states that, for rurally-located industry, it is difficult for primary agricultural dealers from any location to meet the proposed requirements, because, in some of these small businesses, one person assumes many responsibilities. (Response) FDA has considered this and other comments and has changed the record availability requirement from the proposed rule. Under this final regulation, records shall be made available as soon as possible, but not to exceed 24 hours after FDA has made the request. In the circumstances in which FDA would access the records, it is critical for FDA to move as quickly as possible to trace backwards to identify the source of any such adulteration and trace forward from that source to remove all similarly adulterated food from commerce to protect the public health. FDA notes that, although the rule sets an outer limit of 24 hours to provide records, it requires that records be provided as soon as possible. (Comment 149) One comment states that the proposed time for records access is problematic for small-scale exporters that do not have any representation in the United States; hence, they need special treatment. (Response) Foreign persons are not subject to these final recordkeeping regulations, except to the extent they transport food in the United States.

The issue of confidentiality is the most difficult analytically. On the one hand, the business community has accepted the relatively low level of confidentiality provided by the postal system as adequate and the risk of their information being improperly divulged as adequately low. Therefore, it must be demonstrated that the risk of such disclosure on electronic networks is also acceptably low. On the other hand, only cryptographic techniques can provide high confidence of confidentiality. While the installation costs of encryption may be low, the maintenance costs (especially at the administrative level) is an impediment to the use of this technology. Moreover, data encryption is not now in wide use for commercial transactions, even those that are considered sensitive. The Health Care Financing Administration (HCFA) is automating the receipt of financial information from Health Maintenance Organizations (HMOs) . The information is financially sensitive.

HCFA expects to receive about 1900 such reports per year, but each form is currently about 25 to 30 pages of data, on both sides of the page. 2. Evidence --The Federal Rules of Evidence do not address specifically electronic digital data security mechanisms.^ The scope of proof of trustworthiness (and, arguably, security) as an evidentiary foundation requires closer scrutiny. "[B]ecause electronic files are particularly susceptible to purposeful or accidental alteration, or incorrect processing, laying a foundation for their admission must be done with particular care. Proper control over creation and maintenance of these files can be crucial in overcoming inevitable objections that will be raised in the courtroom. The implications of burgeoning, open, interconnected, and highly diverse computer systems utilizing expert system components, which may change frequently and considerably, may call for strong evidentiary foundations.

- Activity 5: Define approaches for communicating to customers. Many customers will benefit from manufacturers communicating to them more clearly about cybersecurity risks involving the IoT devices the manufacturers are currently selling or have already sold. This communication could be targeted at the customer directly or others acting on the customers' behalf, such as an internet service provider or a managed security services provider, depending on context and roles. - Activity 6: Decide what to communicate to customers and how to communicate it. There are many potential considerations for what information a manufacturer communicates to customers for a particular IoT product and how that information will be communicated. Examples of topics are: - o Cybersecurity risk-related assumptions that the manufacturer made when designing and developing the device - o Support and lifespan expectations, such as expected term of support, what process will guide end-of-life, will any functions of the device remain after its end-of-life, how customers can communicate with the manufacturer about suspected vulnerabilities during and even after the end of device support, and how customers may be able to maintain securability after support ends and at end-of-life - o Device composition and capabilities, such as information about the device's software, hardware, services, functions, and data types - o Software updates, such as if updates will be available, when, how and by whom they will be distributed, and how customers can verify source and content of a software update - o Device retirement options, such as if and how a customer can securely transfer ownership of the device, and whether the customer can render the device inoperable for disposal - o Device cybersecurity capabilities that the device provides, as well as cybersecurity functions that can be provided by a related device or a manufacturer service or system 1.

(Response) Both the proposed and final rules require incoming ingredients to be linked specifically to outgoing food products only if that information is reasonably available (as discussed previously). What is reasonably available is determined on a case-by-case basis and depends on the operating practices of a specific facility. FDA does not intend the rule to require covered entities to reconfigure their operations. If cherries from many growers are typically mixed (i.e., commingled), then full information linking ingredient source to final product may not be reasonably available. If, however, the cherries are in separate bins based on supplier or easily can be separated and identified, then full information linking source to final product may be reasonably available. In the PRIA, FDA acknowledged the prohibitive cost of a policy option requiring producers to be able to link specific ingredients to specific food products (option 13 in the proposal). That option was ultimately rejected, in part, because of the high cost of identifying the producers of traditionally commingled raw commodities. Instead, both the proposed and final rules required linkage only when the linkage is reasonably available. 7. Labor Cost Estimates (Comment 202) Several comments suggest that the wage rate used by FDA in the PRIA of \$25.10 is too low. One comment suggests that an hourly wage of \$33 would be more appropriate for the analysis, because it would reflect the need for higher-level personnel involvement due to complexities in the proposed rule. Another comment suggests that the \$25.10 wage is reasonable, but that the hour estimates are too low. (Response) FDA disagrees with the suggestion to increase the wage rate used in the analysis because the implied annual wage and overhead cost of more than \$52,000 seems more than reasonable, as suggested in another comment. (Comment 203) One comment argues that there is no evidence that the wage of \$25.10 used in the analysis has been doubled to account for overhead in any of the calculations. (Response) The hourly wage of an administrative worker reported by the Bureau of Labor Statistics of about \$12.55 was doubled in the computations to account for overhead costs. FDA acknowledges that this was not clearly stated in the PRIA. 8. Learning Costs (Comment 204) Some comments state that FDA's estimate of 3 hours for learning costs is low. The comments state that access to the Internet and lack of fluency in English are not the only costs. The comments maintain that learning cost estimates did not include the time for an FDA explanatory video

and did not include adequate time for evaluating the information in the rule.

(4) The IDA should consult with public affairs officers (PAOs) to become familiar with subject matter considered to be newsworthy at the local or national level, and advise PAOs of all requests from news media representatives. In addition, the IDA should inform PAOs in advance when they intend to withhold or partially (printed page 71860) withhold a record if it appears the withholding action may be a media issue. (b) Reasons for not releasing a record. The following are reasons for not complying with a request for a record pursuant to 5 U.S.C. 552(a)(3) . These reasons are data items that should be maintained in the control system database for ease of retrieval and reporting in the Annual FOIA Report. (1) No records. A reasonable search of files failed to identify responsive records. (2) Referrals. The request is transferred to another DoD Component or Federal agency. (3) Request withdrawn. The request is withdrawn by the requester. (4) Fee-related reason. The requester is unwilling to pay fees associated with a request; the requester is past due in the payment of fees from a previous FOIA request; or the requester disagrees with the fee estimate. (5) Records not reasonably described. A record has not been described with sufficient particularity to enable the DoD Component to locate it by conducting a reasonable search. (6) Not a proper FOIA request for some other reason. The requester has failed to comply with procedural requirements, other than fee-related requirements, imposed by this part or by DoD Component supplementing regulations. (7) Not an agency record. The information requested is not a record within the meaning of the FOIA and this part. (8) Duplicate request. The request is a duplicate request (e.g., a requester asks for the same information more than once). This includes identical requests received through different means (e.g., electronic mail, facsimile, mail, courier) at the same or different times. (9) Other (Specify). Any other reason a requester does not comply with published rules other than those outlined in paragraph (b) of this section. (10) Partial or total denial. The record is denied in whole or in part in accordance with procedures set forth in the FOIA. (c) Reasonably segregable portions.

It is estimated that approximately 160 contractors may be subject to the enhanced security requirements. Of these 160 contractors, 100 are categorized as small businesses with 25-50 end-point systems. The estimated cost of initial implementation of NIST SP 800-172 for each of these contractors is \$202,500. Twenty contractors are estimated to have 50-100 end-point systems (medium businesses) and 40 are expected to have 750-1500 end-point systems (large businesses). The estimated costs of initial implementation for these contractors are approximately \$1,000,000 per medium business and \$2,315,000 per large business. Therefore, the total estimated cost for 160 contractors to implement NIST SP 800-172 is \$132,850,000, of which \$20,250,000 is attributed to 100 small businesses. Annual recurring costs are estimated to be 20 percent of the cost of initial implementation. f. Submit Supporting Documentation To Verify Compliance A contractor may also be required to submit to the Government a description of the system security plan required by NIST SP 800-171 Revision 2 to demonstrate their implementation of the security requirements in NIST SP 800-171 Revision 2. Requests for access to review the system security plan are expected to be rare, such as in response to a reported CUI incident. It is estimated that the system security plan may be requested 1,430 times and that it would take a contractor 30 minutes to submit the plan. The total estimated annual cost is \$67,925 (1 request * 1,430 contractors * 0.5 hours/response * \$95/hour), of which \$46,294 is attributed to 975 small businesses. Note, the cost to develop and maintain a system security plan in accordance with NIST SP 800-171 Revision 2 is attributed only to non-defense contractors (see sections IV.C.2.a. and IV.C.2.d. of this preamble) since defense contractors are subject to NIST SP 800-171 Revision 2 pursuant to DFARS clause 252.204-7012 and should already maintain system security plans. g. Comply With Additional Security Requirements Identified in the Solicitation or Requirements Document In addition to the security requirements outlined in the SF XXX and the new FAR clause at 52.204-XX, the requirements document may require the contractor to comply with controls beyond NIST SP 800-171 Revision 2 to address unique requirements to protect CUI Basic at higher than the moderate confidentiality level in accordance with 32 CFR 2002.14(h)(2) . Similarly, if offerors require access to CUI, the Government will provide agency procedures on handling the CUI to ensure compliance with the requirements in 32 CFR 2002 . The contractor shall also implement additional information security requirements it reasonably determines necessary to provide adequate security in a dynamic environment. Given that agencies have discretion in developing their contract-specific requirements, the Government does not attempt to quantify these costs. h. Comply With Additional Notification and Marking Requirements

3.3.4 Security Capabilities and ISCM To facilitate the implementation of automated security control

assessments, an ISCM program defines specific security capabilities to guide and focus implementation.

· Evaluate the ESP's CRM where the provider identifies security requirement objectives that are the provider's responsibility and security requirement objectives that are the OSA's responsibility. Additional Guidance on Level 2 Scoping CMMC Assessment Scope · Level 2 | Version 2.13 10 · Consider the agreements in place with the ESP, such as service-level agreements, memoranda of understanding, and contracts that support the OSA's information security objectives. · ESPs that are CSPs, o and store, process, or transmit CUI, must meet the FedRAMP requirements in DFARS clause 252.204-7012. o and do NOT store, process, or transmit CUI, are not required to meet FedRAMP requirements in DFARS clause 252.204-7012. Services provided by an ESP are in the OSA's assessment scope. · ESPs that are not a CSP, o and store, process, or transmit CUI, require assessment. The ESP services used to meet OSA requirements are within the scope of the OSA's CMMC assessment. o and do NOT store, process, or transmit CUI, do not require their own CMMC assessment. Services provided by an ESP are in the OSA's assessment scope. o may voluntarily request a C3PAO assessment, and a C3PAO may conduct such an assessment, if the ESP makes that business decision. · OSAs shall also be assessed at Level 2, as applicable, against their on-premise infrastructure connecting to the CSP. As part of the CMMC Assessment Scope, the security requirements from the CRM must be documented or referred to in the OSA's SSP, which will also be assessed. · ESPs can be part of the same corporate/organizational structure but still be external to the OSA such as a centralized SOC or NOC which supports multiple business units. The same requirements apply and are based on whether or not the ESP provides cloud services and whether or not the ESP processes, stores, or transmits CUI on their systems. · An ESP that is used as staff augmentation and the OSA provides all processes, technology, and facilities does not need CMMC assessment. · When ESPs are assessed as part of an OSAs assessment, the type of the assessment is dictated by the OSA's DoD solicitation and contract requirement. Cloud Service Provider (CSP) means an external company that provides cloud services based on cloud computing. Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. An ESP would be considered a CSP when it provides its own cloud services based on a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing that can be rapidly provisioned and released with minimal management effort or service provider interaction. An ESP (not a CSP) that provides technical support services to its clients would be considered a Managed Service Provider. It does not host its own cloud platform offering. An ESP may utilize cloud offerings to deliver services to clients without being a CSP. An ESP that manages a third-party cloud service on behalf of an OSA would not be considered a CSP.

No exclusions, subject to record establishment, maintenance, and access (See § 1.327(k)) Finished container that contacts food All other activities with respect to finished container Excluded from all provisions of the rule, except §§ 1.361 and 1.363 (record access) (See § 1.329(k)) E. Comments on What Definitions Apply to This Subpart? (Proposed § 1.328) 1. General Comments (Comment 63) One comment states that FDA should clarify the meaning of ·responsible individual·. The meaning of the term ·responsible individual· is the same as other terms mentioned in other sections, such as ·emergency contact·. Moreover, it is not clear what responsibilities are included in this term. (Response) FDA agrees with the comment that there is little utility for the record of each commercial transaction involving the distribution of food to contain the name of a responsible individual given that individuals change jobs within and among companies very often, making it unlikely that the person in the record will have responsibility for the food at issue when FDA seeks to effect a traceback. Therefore, FDA deleted the requirement that a name of a ·responsible individual· be included in each record. To the extent this information is available, FDA will use the registration contact information for (printed page 71587) facilities subject to registration requirements under § 1.232. FDA believes that, for facilities not subject to the registration interim final rule, an independent requirement to provide this emergency contact information with the records being kept will not be useful. The stated purpose of having such a contact name is to obtain help in accessing the records. However, to find that information, FDA would have already obtained the records without this emergency contact information. (Comment 64) One comment states that FDA should clarify the meaning of ·Adequate description·. FDA must establish and publish the minimum parameters of the products description. (Response) An adequate description of the food would include the brand name and specific variety (e.g., brand x cheddar cheese, not just cheese; or

romaine lettuce, not just lettuce). This type of description saves time and resources during a tracing investigation because it allows FDA to narrow its focus to the appropriate product during the investigation. (Comment 65) One comment requests that FDA clarify the meaning of 'Holding.' (Response) FDA has defined 'holding' in § 1.328 of this final rule to mean 'storage of food. Holding facilities include warehouses, cold storage facilities, storage silos, grain elevators, and liquid storage tanks.' (Comment 66) One comment states that FDA uses the word 'Importer' but does not define it. (Response) The word 'importer' does not appear in the final regulation. FDA will not define it for purposes of this regulation. 2. The FD&C Act There were no comments on this issue. 3. Domestic Person

published by the Office of the Director of National Intelligence. Commenters were concerned with the lack of guidance on how information systems will be used to report foreign travel and when foreign travel reporting should be accomplished by contractors. Also, commenters requested more details as to who approves foreign travel requests: the contractor security staff, the government customer, or CSA. DoD also received comments from regulated parties stating it would be burdensome for contractors under DoD security cognizance to submit individual foreign travel reports. Regulated parties recommended DoD modify its information technology (IT) system so a contractor may submit multiple or batched foreign travel reports in a single submission. As discussed earlier, to allow time for the completion of modifications to DoD's IT system, DoD published an amendment on August 19, 2021, to extend until August 24, 2022, the implementation date for contractors under DoD security cognizance to report and obtain pre-approval of unofficial foreign travel to DoD. The IT system was modified prior to the August 2022 implementation date and can now receive multiple foreign travel reports at a time. Additionally, one commenter opined the cost to contractors to implement SEAD 3 was underestimated both in (printed page 86290) the time it will take to report and the number of reports that will be generated. We agree with this assessment and the corrected numbers can be found in the cost analysis section of the preamble. Further, commenters asked how the CSA will analyze the reported data and if the analysis will be shared with the contractor or the cleared employee going on foreign travel. For those contractors under DoD cognizance, guidance was provided via an ISL (https://www.dcsa.mil/Portals/128/Documents/CTP/tools/ISL2021-02_SEAD-3.pdf) to provide supplementary procedures and inform industry how compliance with SEAD 3 will be accomplished for unique DoD mission needs. Controlled Unclassified Information DoD received seven comments on CUI as it relates to the paragraphs on security reviews (§ 117.7), training (§ 117.12), and safeguarding CUI (§ 117.15). DoD did not make any changes to the rule as compliance with CUI is outside the scope of the NISP. For the purposes of this rule, if a contractor has a classified contract that also includes provisions for CUI, then, under certain circumstances, CUI assessments may be conducted by the CSA in conjunction with NISP USG reviews. The contractor must follow the requirements as stated in their contract concerning the safeguarding of CUI. Security Reviews

However, OCR has learned through its enforcement experience that many covered entities have entrusted ePHI to business associates that are not employing appropriate safeguards. Some business associates have such market power that covered entities may believe they have no alternative to using their services, even if they have concerns about the safeguards employed by the business associate. The Department is concerned by the breaches experienced by business associates and the effects of such breaches on the confidentiality, integrity, and availability of ePHI. [446] 3. Proposals a. Section 164.308-Administrative Safeguards Throughout this section, the Department proposes to add explicit maintenance requirements to certain standards to address concerns that regulated entities may be misinterpreting the regulatory text that connects the maintenance provision at 45 CFR 164.306(e) with the administrative safeguards. These proposals would clarify that a regulated entity is required to maintain certain security measures, and that where a regulated entity is required to maintain a particular security measure, it is required to review and test such measure on a specified cadence, and to modify the measure as reasonable and appropriate. Testing of particular security measures, such as technical controls or policies and procedures, would include verifying that the security measures work as designed and that workforce members know how to implement them. For example, written policies and procedures can be tested through various methods including, but not limited to: simulating security events that mimic real-world attacks to assess how effectively employees follow incident response and security procedures; conducting knowledge assessments after training on policies and procedures; and reviewing system logs and access records to evaluate whether policies and procedures governing access to ePHI are being followed. We would expect a regulated entity to take the results of the required tests into

consideration when determining whether it is reasonable and appropriate to modify its security measures, as well as the actions that would be expected of a regulated entity that is similarly situated based on the results of such tests. We also propose to modify certain administrative safeguards to clarify the obligations of a regulated entity to ensure the confidentiality, integrity, and availability of ePHI by securing its relevant electronic information systems—that is, its electronic information systems that create, receive, maintain, or transmit ePHI and those that otherwise affect its confidentiality, integrity, or availability—and the technology assets in its relevant electronic information systems. b. Section 164.308(a) The Department proposes to modify the general language at 45 CFR 164.308(a) to clarify the connection between the general rules for security standards at 45 CFR 164.306 , the standards for policies and procedures and documentation requirements at 45 CFR 164.316

<https://www.hhs.gov/hipaa/for-professionals/security/guidance/index.html?language=es> . Back to Citation 491. · See ·Defending Against Common Cyber-Attacks,· supra note 396. Back to Citation 492. ·It may not be reasonable and appropriate for a regulated entity to patch software or update a system configuration where the risk of introducing a change is greater than the status quo risk or where the regulated entity does not own or manage a networked device. For example, instances where it might not be reasonable and appropriate to patch or update an information system include: (1) where a system needs to run continuously for mission critical support and is not patched or updated during its lifetime; and (2) where the regulated entity's testing of such patch or update indicates potential adverse impacts or where industry is reporting adverse impacts of such patch or update. This does not negate the regulated entity's need to address the vulnerability with a compensating control. For example, where a hospital discovers a vulnerability on a device that is connected to its network but owned and managed by a business associate, the hospital may not have access to install a patch, but it should employ a compensating control, such as disabling or limiting that device's access to the hospital's network. Back to Citation 493. · See ·Guidance on Software Vulnerabilities and Patching,· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (June 2018), <https://www.hhs.gov/sites/default/files/june-2018-newsletter-software-patches.pdf> . Back to Citation 494. · See ·Securing Your Legacy [System Security],· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Oct. 2021), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-fall-2021/index.html> . Back to Citation 495. · See ·Guidance on Software Vulnerabilities and Patching,· supra note 493. Back to Citation 496. · See Murugiah Souppaya, et al., ·Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology,· NIST Special Publication 800-40, Revision 4, National Institute of Standards and Technology, U.S. Department of Commerce (Apr. 2022), <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-40r4.pdf> . Back to Citation 497. ·Letter from NCVHS Chair Jacki Monson (2023), supra note 123, Appendix p. 1; Letter from NCVHS Chair Jacki Monson (2022), supra note 123, p. 8-9. Back to Citation 498. ·An explanation of risk rating is provided above in the discussion of the proposed standard for risk analysis and associated implementation specifications. Back to Citation 499. ·Cybersecurity Performance Goals,· supra note 18. Back to Citation 500. · See proposed 45 CFR 164.308(a)(2) . Back to Citation 501. ·Cybersecurity Performance Goals,· supra note 18. Back to Citation

```
3.4.3 ..... 3.4.3 .....
..... Linux
.....
..... OS .....
..... OS
.....
..... OS ..... OS ..... Linux ..... /boot
/etc · Windows ..... C:\Windows .....
..... ## 3.
```

Contractors will reproduce paper copies, electronic files, and other material containing classified information only when necessary for accomplishing operational needs or for complying with contractual requirements. Use of technology that prevents, discourages, or detects unauthorized reproduction of classified information is encouraged. (i) Unless restricted by the GCA on behalf of the originating agency, TOP SECRET, SECRET, and CONFIDENTIAL information may be reproduced,

including by emailing, scanning, and copying, to the extent operational needs require on authorized systems and equipment approved at the level of the classified material and in support of a contractual requirement. (ii) Contractors shall establish procedures that facilitate oversight and control of the reproduction of classified information and the use of equipment for such reproduction, including controls that ensure: (A) Reproduction is kept to a minimum consistent with contractual requirements. (B) Contractor personnel reproducing classified information are knowledgeable of the procedures for classified reproduction and aware of the risks involved with the specific reproduction equipment being used and the appropriate countermeasures they are required to take. (C) Reproduction limitations the GCA places on documents and special controls applicable to special categories of information are fully and carefully observed. (D) Reproduced material is placed under the same accountability and control requirements as applied to the original material. Extracts of documents will be marked according to content and may be treated as working papers if appropriate. (E) Reproduced material is conspicuously identified as classified at the applicable level and copies of classified material are reviewed after the reproduction process to ensure that the required markings exist. (F) Waste products generated during reproduction are protected and destroyed as required. * * * * * 9. Amend § 117.17 by: a. Revising paragraphs (a)(3) introductory text; b. Removing paragraphs (a)(3)(i) through (iii); and (printed page 86295) c. Redesignating paragraphs (a)(3)(iv) introductory text and (a)(3)(iv)(A) and (B) as paragraphs (a)(4) introductory text and (a)(4)(i) and (ii). The revisions read as follows: § 117.17 Subcontracting. (a) * * * (1) * * * (2) * * * (3) Lead time for entity eligibility determination when awarding to an uncleared subcontractor. Requesting contractors will allow sufficient lead time in connection with the award of a classified subcontract to enable an uncleared bidder to be processed for the necessary entity eligibility determination. * * * * * § 117.19 [Amended] 10. Amend § 117.19 in paragraph (b)(5)(iv) by adding the words ·(e.g., a security aspects letter)· at the end of the paragraph. Dated: December 6, 2023. Patricia L. Toppings, OSD Federal Register Liaison Officer, Department of Defense. [FR Doc. 2023-27171 Filed 12-12-23; 8:45 am] BILLING CODE 5001-06-P

(D) Require CMMC Ecosystem members to actively avoid participating in any activity, practice, or transaction that could result in an actual or perceived conflict of interest. (E) Require CMMC Ecosystem members to disclose to Accreditation Body leadership, in writing, any actual or potential conflict of interest as soon as it is known, or reasonably should be known. (ii) Code of Professional Conduct (CoPC) policy. The CoPC policy shall: (A) Describe the performance standards by which the members of the CMMC ecosystem will be held accountable and the procedures for addressing violations of those performance standards. (B) Require the Accreditation Body to investigate and resolve any potential (printed page 89125) violations that are reported or as identified by the DoD. (C) Require the Accreditation Body to inform the DoD in writing of new investigations within 72 hours. (D) Require the Accreditation Body to report to the DoD in writing the outcome of completed investigations within 15 business days. (E) Require CMMC Ecosystem members to represent themselves and their companies accurately; to include not misrepresenting any professional credentials or status, including CMMC authorization or certification status, nor exaggerating the services that they or their company are capable or authorized to deliver. (F) Require CMMC Ecosystem members to be honest and factual in all CMMC-related activities with colleagues, clients, trainees, and others with whom they interact. (G) Prohibit CMMC Ecosystem members from participating in the CMMC assessment process for a CMMC assessment in which they previously served as a consultant to prepare the organization for any CMMC assessment. (H) Require CMMC Ecosystem members to maintain the confidentiality of customer and government data to preclude unauthorized disclosure. (I) Require CMMC Ecosystem members to report results and data from assessments and training objectively, completely, clearly, and accurately. (J) Prohibit CMMC Ecosystem members from cheating, assisting another in cheating, or allowing cheating on CMMC examinations. (K) Require CMMC Ecosystem members to utilize official training content developed by a CMMC training organization approved by the CAICO in all CMMC certification courses. (iii) Ethics policy. The Ethics policy shall: (A) Require CMMC Ecosystem members to report to the Accreditation Body within 30 days of convictions, guilty pleas, or no contest pleas to crimes of fraud, larceny, embezzlement, misappropriation of funds, misrepresentation, perjury, false swearing, conspiracy to conceal, or a similar offense in any legal proceeding, civil or criminal, whether or not in connection with activities that relate to carrying out their role in the CMMC ecosystem. (B) Prohibit harassment or discrimination by CMMC Ecosystem members in all interactions with individuals whom they encounter in connection with their roles in the CMMC ecosystem.

ially be used for identity services and Near Field Communication (NFC). If these mitigations are

important to a user(s), they may need to request these security protections from the appropriate party. Many of the listed mitigations may simply be modifying certain configurations of already implemented features, something that would be feasible in the near term. Others would require software updates to mobile operating systems, and/or baseband processors, or modifications to 3GPP standards, which will take much more time to implement.

(z) For service acquisitions that will require a contractor to develop, implement, operate, or maintain a Federal information system, ensuring that acquisition planners (see 2.101(b)), in consultation with the agency's authorizing official (see 39.X01), develop requirements in accordance with the procedures at 39.X02-1 and 39.X02-2. 8. Amend section 7.105 by removing from paragraph (b)(18)(iii) ~~·Federally-controlled information·~~ and adding ~~·Federal information·~~ in its place and adding paragraph (b)(18)(v) to read as follows: 7.105 Contents of written acquisition plans. * * * (b) *** (18) *** (v) For service acquisitions that will require a contractor to develop, implement, operate, or maintain a Federal information system, discuss compliance with 39.X02-1 and 39.X02-2. * * * * * PART 10·MARKET RESEARCH 10.001 [Amended] 9. Amend section 10.001 by removing from paragraph (a)(3)(ix) ~~·information and communication technology·~~ and adding ~~·information and communications technology·~~ in its place. PART 11·DESCRIBING AGENCY NEEDS 11.002 [Amended] 10. Amend section 11.002 by removing from paragraph (f)(1)(i) ~~·information and communication technology·~~ and adding ~~·information and communications technology·~~ in its place. PART 12·ACQUISITION OF COMMERCIAL PRODUCTS AND COMMERCIAL SERVICES 12.202 [Amended] 11. Amend section 12.202 by removing from paragraph (d) ~~·information and communication technology·~~ and adding ~~·information and communications technology·~~ in its place. PART 37·SERVICE CONTRACTING 37.000 [Amended] 12. Amend section 37.000 by removing from the text ~~·information technology·~~ and adding ~~·information and communications technology·~~ in its place. PART 39·ACQUISITION OF INFORMATION AND COMMUNICATIONS TECHNOLOGY 13. Revise the heading for part 39 to read as set forth above. 14. Amend section 39.000 by removing from paragraph (a) ~~·Management of Federal Information Resources·~~ and adding ~~·Managing Information as a Strategic Resource·~~ in its place; and revising paragraph (b) to read as follows: 39.000 Scope of part. * * * * * (b) Information and communications technology (ICT), as well as supplies and services that use ICT (see 2.101(b)). 15. Amend section 39.001 by revising the first sentence of paragraph (a) and revising paragraph (b) to read as follows: 39.001 Applicability. * * * * * (a) ICT, as well as supplies and services that use ICT, which includes information technology, Internet of Things (IoT) devices (e.g., connected appliances, wearables), and operational technology, by or for the use of agencies except for acquisitions of information technology for national security systems. *** (b) ICT by or for the use of agencies or for the use of the public. When applying the policy in subpart 39.2, see the exceptions at 39.204 and exemptions at 39.205. 16. Revise subpart 39.2 heading to read as follows: Subpart 39.2·Information and Communications Technology Accessibility * * * * * 39.201 [Amended] 17.

The data center threat landscape has evolved in recent years to encompass more advanced attack surfaces with more persistent attack mechanisms. With increased attention being applied to highlevel software security, attackers are pushing lower in the platform stack, forcing security administrators to address a variety of attacks that threaten the platform firmware and hardware. These threats can result in: Existing mitigations of threats against cloud servers are often rooted in firmware or software, making them vulnerable to the same attack strategies. For example, if the firmware can be successfully exploited, the firmware-based security controls can most likely be circumvented in the same fashion. Hardware-enabled security techniques can help mitigate these threats by establishing and maintaining platform trust -an assurance in the integrity of the underlying platform configuration, including hardware, firmware, and software. By providing this assurance, security administrators can gain a level of visibility and control over where access to sensitive workloads and data is permitted. Platform security technologies that establish platform trust can provide notification or even self-correction of detected integrity failures. Platform configurations can automatically be reverted back to a trusted state and give the platform resilience against attack. In addition, there are other hardware platform security technologies that can protect data at rest, in transit, and in use by providing hardware-accelerated disk encryption or encryption-based memory isolation. Many of these capabilities can help mitigate threats from speculative execution and side-channel attacks. By using hardware to perform these tasks, the attack surface is mitigated, preventing direct access or modification of the required firmware. Isolating these encryption mechanisms to dedicated hardware can allow performance to be addressed and enhanced separately from other system processes as well.

According to Guidelines for Access Control System Evaluation Metrics, Executive Summary: Executive Summary Adequate security of information and information systems is a fundamental management responsibility. Nearly all applications include some form of access control (AC). AC is concerned with determining the allowed activities of legitimate users, mediating every attempt by a user to access a resource in the system. AC is concerned with how authorizations are structured; in some systems, complete access is granted after successful authentication of the user, but most systems require more sophisticated and complex control. There are three primary abstractions used in AC system planning: AC policies, models, and mechanisms. AC policies are high-level requirements that specify how access is managed and who may access information under what circumstances. At a high level, AC policies are enforced through a mechanism that translates a user's access request, often in terms of a structure that a system provides. AC models bridge the gap in abstraction between policy and mechanism. Rather than attempting to evaluate and analyze AC systems exclusively at the mechanism level, AC models are usually written to describe the security properties of an AC system. AC systems come with a wide variety of features and administrative capabilities, and their operational impact can be significant. In particular, this impact can pertain to administrative and user productivity, as well as to the organization's ability to perform its mission. Therefore, it is reasonable to use quality metrics to verify the mechanical properties of AC systems.

a CMMC Status of Conditional/Final Level 2 (Self-), then the Level 2 self-assessment score with a current affirmation is valid for that contract but not for a contract with a Level 2 certification assessment requirement. The DoD does not consider it realistic or likely that C3PAOs will purposefully slow roll completion of assessments for which they have been engaged by an OSC. However, the OSA's CMMC Status is based on final results of an assessment and a valid affirmation. A POA&M Close-out assessment need only re-assess those requirements that were assessed as NOT MET in the original assessment as addressed in § 170.21(b). The OSA status is based on the results of this POA&M Close-out assessment with a valid affirmation. If the subcontractor will process, store, or transmit CUI, then the flow down requirement for a Prime contract that specifies CMMC Level 3 certification assessment is, at a minimum, CMMC Level 2 certification assessment (i.e., a CMMC Status of Conditional/Final Level 2 (C3PAO)). A POA&M closeout applies to all NOT-MET requirements so if one practice is not remediated within the 180-day time limit, the conditional certification will expire. Scope cannot be changed in the middle of an assessment, so the conditional certification will expire. If the scope is changed, a new assessment is required. The assessment is performed based on the defined CMMC Assessment Scope. The OSA is only approved to process, store, or transmit FCI and CUI within the CMMC Assessment Scope defined. If the conditional assessment certification expires due to exceeding the 180-day limit, a new full certification assessment is required. Contracting officers can utilize standard contract remedies during any period under which the OSA is not in compliance with CMMC requirements. If an OSC closed out their POA&M 32 months ago, that Level 2 Conditional certification assessment would have closed and the OSC would have received a Level 2 Final certification assessment for the remainder of the 3-year validity period. If after completing the Level 2 Final certification assessment, the OSC is reassessed and does not achieve a score of 110, then the OSC will either get a new Conditional Level 2 (C3PAO) CMMC Status certificate (if they meet the associated POA&M requirements), or the OSC will not receive a new certificate. c. Level 3 Comment: Several comments addressed CMMC Level 3 assessment requirements and the relationship of Level 3 assessments to Level 2 assessments. One comment noted that a final version of the Level 3 assessment guidance was not available at the same time as other CMMC assessment guides. Another recommended the DoD first pilot implementation of CMMC Level 3 security requirements and clearly identify (in advance) the data or programs that will be subject to them. One commenter asked how DoD will maintain Level 3 requirements to align with NIST's guidance since Level 3 includes only a subset of NIST's SP 800-172 Feb2021 requirements.

Also, retail food establishments that employ 10 or fewer full-time equivalent employees are now excluded from all of the requirements in this subpart, except §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) (Comment 139) A few comments state that the requirement to maintain records for 2 years is very burdensome for those who obtain a variety of fresh produce from a large number of small farmers and commingle lots of produce for distribution. (Response) FDA notes that these foods for the most part would fall into the category of foods for which a significant risk of spoilage or significant loss of value occurs if held longer than 60 days under normal shipping and storage conditions for the food. As stated previously, the record retention period for this category of foods in this final

rule is 6 months. (Comment 140) A few comments state that, for alcoholic beverages and distilled spirits, retention of records for a period of only 2 years would be inadequate to trace a matured product back to the source. They suggest that FDA should rely on alcoholic beverage importers' and producers' own existing record systems to facilitate tracebacks. (Response) Although retaining records for 2 years may not be enough for products with long shelflives, the agency notes that the Bioterrorism Act sets the maximum time the agency can mandate record retention at 2 years. FDA further notes, however, that when FDA has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals, any records and other information accessible to FDA under section 414 or 704(a) of the FD&C Act must be readily available for inspection and photocopying or other means of reproduction. Therefore, as a practical matter, FDA may be able to access additional information about food products after the 2-year retention period required by subpart J of this final rule has elapsed.

asures for Microcomputers | Special Protective Measures for Microcomputers | 6-1 | | a. | Technical Protective Measures | 6-1 | | b. | Administrative Protective Measures | 6-2 | | c. | Physical Protective Measures | 6-2 | | d. | Personnel Protective Measures | 6-2 | | APPENDICES | APPENDICES | | APPENDIX | A. | REFERENCES | A-1 | | APPENDIX | B. | ABBREVIATIONS | B-1 | | APPENDIX | C. | DEFINITIONS | C-1 | | APPENDIX | D. | LIST OF EXHIBITS | D-1 | | APPENDIX | E. | CLASSIFIED SYSTEM SECURITY PLAN | E-1 |

SC.L2-3.13.3 · Role Separation CMMC Assessment Guide · Level 2 | Version 2.13 218 FURTHER DISCUSSION Prevent users and user services from accessing system management functionality on IT components (e.g., databases, network components, workstations, servers). This reduces the attack surface to those critical interfaces by limiting who can access and how they can be accessed. By separating the user functionality from system management functionality, the administrator or privileged functions are not available to the general user. The intent of this requirement is to ensure: · general users are not permitted to perform system administration functions; and · system administrators only perform system administration functions from their privileged account. This can be accomplished using separation like VLANs or logical separation using strong access control methods. Example As a system administrator, you are responsible for managing a number of core systems. Policy prevents you from conducting any administration from the computer or system account you use for day-to-day work [a,b]. The servers you manage also are isolated from the main corporate network. To work with them you use a special unique account to connect to a ·jump· server that has access to the systems you routinely administer. Potential Assessment Considerations · Are physical or logical controls used to separate user functionality from system management-related functionality (e.g., to ensure that administration (e.g., privilege) options are not available to general users) [c]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.13.3

Guidelines (VVSG) 1.1. The security guidelines were updated in FY 2012 to improve the auditability of voting systems, to provide greater software integrity protections, to expand and improve access control requirements, and to help ensure cryptographic security mechanisms are implemented properly. In addition, CSD supported the efforts of the EAC and Federal Voting Assistance Program (FVAP) of DoD to improve the voting process for citizens under the Uniformed and Overseas Citizens Voting Act (UOCAVA) by leveraging electronic technologies. The team worked with the TDCG's UOCAVA Working Group to develop a risk analysis on technologies used in current UOCAVA voting processes, including vote-by-mail, online voter registration, electronic ballot delivery, and online ballot marking. - — Updates on the OCR privacy, security, and breach notification audit program - — Patient and provider identity management, HIPAA requirements in cloud and mobile environments - — HIPAA rule changes affecting breach notification and HIPAA security - — Cybersecurity Framework for improving critical infrastructure cybersecurity - — Health IT activities at the National Cybersecurity Center of Excellence - — Methods for managing insider threat - — Tools available to manage security settings on end-user devices This year's annual 2-day offsite meeting featured updates on the computer security activities of the Government Accountability Office (GAO), General Services Administration (GSA), Bureau of the Fiscal Service, and NIST. Recent administration guidance directing federal agencies to reduce travel and conference budgets significantly reduced attendance.

FDA plans similar outreach directed to stakeholders following publication of the final rule implementing the recordkeeping provisions of the Bioterrorism Act. Our outreach will include the following: Materials and events for the media; Domestic outreach meetings to States and industry; International outreach to U.S. trading partners; Presentations by FDA officials and exhibits at

professional and trade conferences and meetings to inform industry and State and local government representatives of the new regulations and their requirements; and Cooperative arrangements with other Federal agencies to ensure that information on the final regulations and their requirements is disseminated to affected companies and individuals. More specifics regarding each of these will be included on FDA's Web site at <http://www.fda.gov/oc/bioterrorism/bioact.html>. (Comment 10) Several comments suggest that, to lessen the burden to the food industry, FDA needs to coordinate with other local, Federal, and State government security programs in establishing the final recordkeeping regulations. (Response) In issuing these recordkeeping regulations, FDA has stated that records established and maintained as a result of local, State, or other Federal regulations, or as a matter of routine business practice, need not be duplicated if the records contain all the information required by these regulations. Further, if existing records contain some, but not all, of the required information, persons may supplement existing records with the additional information required under this final rule. (Comment 11) One comment asks that the final rule require that upstream entities provide all the required information to downstream entities in the food distribution system. The comment states that distribution centers that receive and store food and retail outlets that hold and sell food do not know and should not be required to determine many of the information items required under the proposed regulation. The comment states that requiring that any information be passed through the system from the first point of distribution, preferably through electronic means, would alleviate some of the burden of the recordkeeping requirements on downstream entities.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. CJI is commonly accessed using computer-aided dispatch (CAD) and record management system (RMS) software, which communicate with a state-level message switch application. CJI MFA architectures will likely need to integrate with one or both of these technologies. As agencies around the country begin to implement MFA solutions, the approaches they use require careful consideration and planning. This document provides a general overview of MFA, outlines design principles and architecture considerations for implementing MFA to protect CJI, and offers specific examples of use cases that agencies face today. It also outlines how CAD/RMS and message switch technologies can support standards and best practices that provide agencies with maximum optionality to implement MFA in a way that promotes security, interoperability, usability, and cost savings. As agencies around the country begin to implement this requirement, they face several challenges that require careful consideration and planning. The purpose of this document is to help agencies identify and address their MFA implementation needs by providing insight into MFA architectures and how they can be used to meet law enforcement-specific use cases.

3.3.1 Intel Trust Domain Extensions (Intel TDX) Intel Trust Domain Extensions (Intel TDX) introduces new architectural elements to deploy hardware-isolated VMs called trust domains (TDs).

(I) From subsection (e)(5) because in the collection of information for law enforcement purposes it is impossible to determine in advance what information is accurate, relevant, timely, and complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light and the accuracy of such information can only be determined in a court of law. The restrictions of subsection (e)(5) would restrict the ability of trained investigators and intelligence analysts to exercise their judgment in reporting on investigations and impede the development of intelligence necessary for effective law enforcement. (J) From subsection (e)(8) because the individual notice requirements of subsection (e)(8) could present a serious impediment to law enforcement as this could interfere with the ability to issue search authorizations and could reveal investigative techniques and procedures. (K) From subsection (f) because this system of records has been exempted from the access provisions of subsection (d). (L) From subsection (g) because this system of records is compiled for law enforcement purposes and has been exempted from the access provisions of subsections (d) and (f). (8) System identifier and name. F071 JTF A, Computer Network Crime Case System. (i) Exemption. (A) Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency, which performs as its principle function any activity pertaining to the

enforcement of criminal laws. Any portion of this system of records which falls within the provisions of 5 U.S.C. 552a(j)(2) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3), (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (H), and (I), (e)(5), (e)(8), (f), and (g). (B) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (e)(8)(i)(B). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Any portion of this system of records which falls within the provisions of 5 U.S.C. 552a(k)(2) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (H) and (I), and (f). (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(2). (iii) Reasons.

Physical access controls to support infrastructure include locked wiring closets; disconnected or locked spare jacks; protection of cabling by conduit or cable trays; and wiretapping sensors. PE.L2-3.10.2 · Monitor Facility CMMC Assessment Guide · Level 2 | Version 2.13 183 FURTHER DISCUSSION The infrastructure inside of a facility, such as power and network cables, is protected so that visitors and unauthorized employees cannot access it. The protection is also monitored by security guards, video cameras, sensors, or alarms. Example You are responsible for protecting your IT facilities. You install video cameras at each entrance and exit, connect them to a video recorder, and show the camera feeds on a display at the reception desk [c,d]. You also make sure there are secure locks on all entrances, exits, and windows to the facilities [a,b]. Potential Assessment Considerations · Is physical access monitored to detect and respond to physical security incidents [c, d]? KEY REFERENCES · NIST SP 800-171 Rev 2 3.10.2

Two comments recommended the draft DFARS regulatory initiative on Safeguarding Unclassified DoD Information (Safeguarding Rule) being addressed under DFARS Case 2011-D039 be written to avoid conflicting and duplicative requirements for participants in the DIB CS/IA program. Response: The DoD is committed to using both internal coordination processes, and public review and comment procedures such as those used in rulemaking for this program and for proposed DFARS revisions, to ensure that its cyber security activities are evaluated to avoid conflicting or duplicative elements. No change is made to the rule. Comment: Two comments recommended specific word changes to the program requirements relating to each party conducting a legal review of its policies and practices that support the program, including deletion of the requirement for a determination of compliance with law because it may be interpreted as requiring the company to retain outside counsel for such a determination, limiting the compliance only to U.S. law, and deleting the second sentence of § 236.6(c) to avoid threatening the attorney-client privilege. Response: The requirement at § 236.6(c) for a determination of legal compliance is expressly stated as a requirement that the DIB participant shall perform a legal review . . . and shall make a determination that it is compliant. There is neither an express nor implied requirement that the DIB participant retain outside counsel for such a determination, and thus no change to that language is warranted. In § 236.6, the rule retains applicable laws and regulations as an accurate description of the requirement. Finally, the second sentence of § 236.6(c) was intended merely to provide notice that the Government may request additional information from the DIB company, and was not intended to imply that there was a requirement to provide such information as a condition of the program, regardless of whether such information were protected by the attorney-client privilege. To avoid any unnecessary confusion or unintended implications, the second sentence is deleted. Comment: One comment expressed full support for the Defense Industrial Base Voluntary Cyber Security and Information Assurance Activities. Response: Government evaluation of the program concurs that the voluntary DIB CS/IA program contributes to the safeguarding of DoD information. No change is made to the rule. Comment: One comment urged a renewed look at how classification schemes are balanced with disclosure schemes. Response: In accordance with the rule (§ 236.4(f)), handling and safeguarding of classified GFI shall be in compliance with the National Industrial Security Program Operating Manual (NISPOM) (DoD 5220.22-M). No change is made to the rule. Comment: One comment recommended that the DIB CS/IA program have a more robust role in industry engagement. Response:

(d) The Chairman of the Joint Chiefs of Staff shall ensure that joint doctrine is consistent with

the principles established by DoD Directive 3020.49, ·Orchestrating, Synchronizing, and Integrating Program Management of Contingency Acquisition Planning and Its Operational Execution,· [6] DoD Instruction 3020.41, ·Contractor Personnel Authorized to Accompany the U.S. Armed Forces,· and this part. (e) The geographic Combatant Commanders in whose AOR a contingency operation is occurring, and within which PSCs and PSC personnel perform under covered contracts, shall: (1) Provide guidance and procedures, as necessary and consistent with the principles established by DoD Directive 3020.49, ·Orchestrating, Synchronizing, and Integrating Program Management of Contingency Acquisition Planning and Its Operational Execution,· DoD Instruction 3020.41, ·Contractor (printed page 49657) Personnel Authorized to Accompany the U.S. Armed Forces,· [7] and this part, for the selection, training, accountability and equipping of such PSC personnel and the conduct of PSCs and PSC personnel within their AOR. Individual training and qualification standards shall meet, at a minimum, one of the Military Departments' established standards. Within a geographic combatant command, a sub unified commander or JFC shall be responsible for developing and issuing implementing procedures as warranted by the situation, operation, and environment, in consultation with the relevant Chief of Mission in designated areas of combat operations or other significant military operations. (2) Through the Contracting Officer, ensure that PSC personnel acknowledge, through their PSC, their understanding and obligation to comply with the terms and conditions of their covered contracts. (3) Issue written authorization to the PSC identifying individual PSC personnel who are authorized to be armed. Rules for the Use of Force shall be included with the written authorization, if not previously provided to the contractor in the solicitation or during the course of contract administration. Rules for the Use of Force shall conform to the guidance in the Chairman of the Joint Chiefs of Staff Instruction 3121.01B, ·Standing Rules of Engagement/Standing Rules for the Use of Force for U.S. Forces,· Access by offerors and contractors to the rules for the use of force may be controlled in accordance with the terms of FAR 52.204-2 (Aug 1996), DFARS 252.204-7000 (Dec 1991), or both. [8] (4) Ensure that the procedures, orders, directives and instructions prescribed in §.159.6(a) of this part are available through a single location (to include an Internet Web site, consistent with security considerations and requirements). (f) The Heads of the DoD Components shall: (1) Ensure that all private security-related requirement documents are in compliance with the procedures listed in §.159.6 of this part and the guidance and procedures issued by the geographic Combatant Command,

3.2.2 | Resource Access Control | 3-10 | | | 3. 3.2.2. 3.2.2 Resource Access Control Once the user has been granted access to the system as a whole, the question of which resources that authenticated user may access still remains.

- Experimentation is a systematic approach to testing new ideas, methods, or activities that applies principles and techniques at the data collection stage to ensure the generation of valid, defensible, and supportable conclusions. A recognizable use of experimentation to collect information security data is a phishing test, which is a form of internal security testing where organizations send fake phishing emails to determine which users respond to it. The rates of success are then judged against set criteria. - Observational data refers to capturing data through the observation of an activity or behavior without the direct involvement of the subject. Observational data is often gathered as part of routine information security operations, such as log management tools that are used to collect and analyze network activities. Data from these logs is observational and can be used for further analysis. - Sampling is the process of taking samples of something for the purpose of analysis. Sampling may be used when continuous observation and passive data collection are not an option or when random , stratified , or systematic sampling may be preferred. Random sampling is a method of sampling in which each sample has an equal chance of selection in hopes of gathering an unbiased representation. Stratified sampling is the process of segmenting a population across levels of some factors to minimize variability within those segments (e.g., taking a sample from a terminal in each department of an organization). Stratified sampling may help an assessment target organizational units without being overwhelmed by noisy data collection but can provide biased results. Systematic sampling involves taking samples at a regular interval (e.g., once an hour or from every tenth user). Systematic sampling is useful for identifying macro-trends but may not provide enough conclusive measurements for the entire population if an underlying pattern is present. 1.

(g) If an appeal under this section is denied in whole or in part, the individual has the right to file a Statement of Disagreement that states the reason(s) for disagreeing with the DoD Component's denial of the request for amendment or correction. Statements of Disagreement must be concise, must

clearly identify each part of any record that is disputed, and should generally be no longer than one typed page. The Statement of Disagreement must be sent to the DoD Component holding the respective record. The Statement of Disagreement will be filed or notated in the system of records, and an annotation to the record itself will indicate the existence and location of the Statement of Disagreement. (h) Notifications of amendment/correction or statements of disagreement will be made to all persons, organizations, and agencies to which the record was previously disclosed if an accounting of that disclosure was made in accordance with subsection (c) of the Privacy Act and § 310.9. If an individual has filed a Statement of Disagreement, a copy of the statement will be appended to the disputed record whenever the record is disclosed, and a concise statement of the reason(s) for denying the request to amend or correct the record may also be appended. § 310.8 Civil remedies. In addition to the right to judicial review after a denied appeal for access to or amendment of a record, the requester has the right to bring a civil action against the Department if the Department: (a) Fails to maintain a record concerning the individual with such accuracy, relevance, timeliness and completeness as is necessary to assure fairness in any determination relating to the qualifications, character, rights, opportunities of, or benefits to the individual that may be made on the basis of such record, and consequently a determination is made which is adverse to the individual; or (b) Fails to comply with any other provision of the Privacy Act or this rule, in such a way as to have an adverse effect on the individual. § 310.9 Requests for an accounting of record disclosures. (a) An individual may make a request for an accounting of any disclosure that has been made by the Department to another person, organization, or agency of any record about the individual maintained in a system of records. (b) This accounting contains the date, nature, and purpose of each disclosure, as well as the name and address of the person, organization, or agency to which the disclosure was made. Records of disclosure accountings are maintained for five years after the disclosure or for the life of the record, whichever is longer. (c) The request for an accounting should identify each particular record in question and should be made by writing directly to the DoD Component that maintains the record, following the procedures in § 310.3. (d) DoD Components are not required to provide disclosure accountings when related to:

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204, 209, 212, 225, and 252 RIN 0750-AI34 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to clarify and relocate text relating to state sponsors of terrorism (as identified by the Department of State), add an explicit representation, and conform the terminology. DATES: Effective December 11, 2014. FOR FURTHER INFORMATION CONTACT: Ms. Amy G. Williams, telephone 571-372-6106. SUPPLEMENTARY INFORMATION: I. Background DoD published a proposed rule in the Federal Register at 79 FR 45666 on August 5, 2014, to clarify and relocate coverage relating to state sponsors of terrorism (as identified by the Department of State), add an explicit representation, and conform the terminology. No respondents submitted public comments in response to the proposed rule. This rule is part of DoD's retrospective plan, completed in August 2011, under Executive Order 13563, Improving Regulation and Regulatory Review. DoD's full plan and updates can be accessed at: <http://www.regulations.gov/#!docketDetail;dct=FR+PR+N+O+SR;rpp=10;po=0;D=DOD-2011-OS-0036>. II. Discussion and Analysis No public comments were received. The final rule is the same as the proposed rule, except for minor edits. III. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804. IV. Regulatory Flexibility Act DoD certifies that this rule will not have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601, et seq.,

) From subsection (e)(5) because many of the records in this system coming from other system of records are derived from other agency record systems and therefore it is not possible for NGA to ensure their compliance with this provision, however, NGA has implemented internal quality assurance procedures to ensure that data used in the matching process is as thorough, accurate, and current as possible. In addition, in the collection of information for law enforcement, counterterrorism, and intelligence purposes, it is impossible to determine in advance what information is accurate, relevant, timely, and complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. The restrictions imposed by (e)(5) would limit the ability of those agencies' trained investigators and intelligence analysts to exercise their judgment in conducting investigations and impede the development of intelligence necessary for effective law enforcement and counterterrorism efforts. However, NGA has implemented internal quality assurance procedures to ensure that the data used in the matching process is as thorough, accurate, and current as possible. (9) From subsection (e)(8) because to require individual notice of disclosure of information due to compulsory legal process would pose an impossible administrative burden on NGA and other agencies and could alert the subjects of counterterrorism, law enforcement, or intelligence investigations to the fact of those investigations when not previously known. (10) From subsection (f) (Agency Rules) because portions of this system are exempt from the access and amendment provisions of subsection (d). (11) From subsection (g) to the extent that the system is exempt from other specific subsections of the Privacy Act. (3) System identifier and name. NGA-003, National Geospatial-Intelligence Agency Enterprise Workforce System. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (a)(3)(i). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (ii) Authority. 5 U.S.C. 552a (k)(2). (iii) Reasons. Pursuant to 5 U.S.C. 552a(k)(2) , the Director of NGA has exempted this system from the following provisions of the Privacy Act, subject to the limitation set forth in 5 U.S.C. 552a(c)(3)

The Department proposes to expand the list of activities that should be considered under the term by adding the activities of ·deleting· and ·transmitting·. The Department also proposes to replace ·system resource· with ·component of an information system· to rely on an already defined term, ·information system·. The proposed modification would clarify that the term includes any and all components of an information system and an information system as a whole. Additionally, the Department believes that a component of an information system better describes how the term access applies today because it is inclusive of hardware, software, and people, as opposed to only the inherent capabilities that contribute to performance, such as system memory and hard disk space. 2. Clarifying the Definition of ·Administrative Safeguards· a. Current Provision and Issues To Address Administrative safeguards are administrative actions, policies, and procedures to manage the selection, development, implementation, and maintenance (including reviewing and modifying) of security measures to protect ePHI. [350] Administrative safeguards also manage the conduct of the regulated entity's workforce in relation to the protection of ePHI. Under the Security Rule, there are minor inconsistencies in language between the definitions of the types of safeguards, which might lead to uncertainty about how to interpret the terms and lead to unintended consequences. For example, the definitions of ·administrative safeguards· and ·physical safeguards· use ·are,· while the definition of technical safeguards uses ·means·. [351] In addition, the existing definition of ·administrative safeguards· does not expressly relate the administrative actions to the policies and procedures addressing the activities covered by the definition, nor does it make clear that the policies and procedures are in addition to the administrative actions. The same is true for the definitions of physical and technical safeguards. Further, the definition of ·administrative safeguards· does not expressly mention managing updates and modifications to safeguards. b. Proposal

Transmission of CNWDI outside the contractor's facility is authorized only to the GCA, or to a subcontractor as described in paragraph (d) of this section. Any other transmission must be approved by the GCA. (1) Prior to transmission to another cleared facility, the contractor will verify from the CSA that the facility has been authorized access to CNWDI. When CNWDI is transmitted to another

facility, the inner wrapping will be addressed to the personal attention of the FSO or his or her alternate, and in addition to any other prescribed markings, the inner wrapping will be marked: Critical Nuclear Weapon Design Information-DoD Instruction 5210.02 Applies. (printed page 83359) (2) The same marking will be used on the inner wrapping of transmissions addressed to the GCA or other USG. (f) Records. Contractors will annotate CNWDI access in the CSA-designated database for all employees who have been authorized access to CNWDI. (g) Nuclear weapon data. Some nuclear weapon data is divided into Sigma categories, the protection of which is prescribed by DOE Order 452.8 (available at: <https://www.directives.doe.gov/directives-documents/400-series/0452.8-border/@images/file>). However, certain nuclear weapon data has been re-categorized as CNWDI and is protected as described in this section. §.117.21 COMSEC. (a) General. The procedures in this section pertaining to classified COMSEC information will apply to contractors when the contractor: (1) Requires the use of COMSEC systems in the performance of a contract. (2) Is required to install, maintain, or operate COMSEC equipment for the USG. (3) Is required to accomplish research, development, or production of COMSEC systems, COMSEC equipment, or related COMSEC material. (b) Instructions. Specific requirements for the management and safeguarding of COMSEC material in industry are established in the COMSEC material control and operating procedures provided to the account manager of each industrial COMSEC account by the agency central office of record (COR) responsible for establishing the account. Such procedures that are above the baseline requirements detailed in the other sections of this rule will be contractually mandated. (c) Clearance and access requirements. (1) Before a COMSEC account can be established and a contractor may receive or possess COMSEC material accountable to a COR, individuals occupying the positions of FSO, COMSEC account manager, and alternate COMSEC account manager must have a final PCL appropriate for the material to be held in the account. (i) COMSEC account managers and alternate COMSEC account managers having access to operational TOP SECRET keying material marked as CRYPTO must have a final TOP SECRET security clearance based upon a current investigation of a scope that meets or exceeds that necessary for the access required. (ii) This requirement does not apply to contractors using only data transfer devices and seed key.

Revising the section heading; b. Redesignating paragraph (2)(xv) as (2)(xvi); and c. Adding a new paragraph (2)(xv). The revision and addition read as follows: 204.1202 Solicitation provision and contract clause. * * * * * (2) * * * (xv) 252.232-7015, Performance-Based Payments-Representation. * * * * * (printed page 19688) PART 212-ACQUISITION OF COMMERCIAL ITEMS 212.001 [Amended] 4. Amend section 212.001 by removing the definition of Nontraditional defense contractor. PART 232-CONTRACT FINANCING 5. In section 232.1001, revise paragraph (a) to read as follows: 232.1001 Policy. (a) As with all contract financing, the purpose of performance-based payments is to assist the contractor in the payment of costs incurred during the performance of the contract. See PGI 232.1001(a) for additional information on use of performance-based payments. However, in accordance with 10 U.S.C. 2307(b)(2) , performance-based payments shall not be conditioned upon costs incurred in contract performance, but on the achievement of performance outcomes. Subject to the criteria in 232.1003-70, all companies, including nontraditional defense contractors, are eligible for performance-based payments, consistent with best commercial practices. * * * * * 6. Revise section 232.1003-70 to read as follows: 232.1003-70 Criteria for use. In accordance with 10 U.S.C. 2307(b)(4)(A) , a contractor's financial statements shall be in compliance with Generally Accepted Accounting Principles in order to receive performance-based payments. 10 U.S.C. 2307(b)(4)(B) specifies that it does not grant the Defense Contract Audit Agency the authority to audit compliance with Generally Accepted Accounting Principles. 7. In section 232.1004, revise paragraph (b) to read as follows: 232.1004 Procedures. (b) Establishing performance-based finance payment amounts. (i) The contracting officer should include in a solicitation both the progress payments and performance-based payments provisions and clauses prescribed in this part, when considering both types of payment methods. Only one type of financing will be included in the resultant contract, except as may be authorized on separate orders subject to FAR 32.1003(c)). (ii) The contracting officer shall analyze the performance-based payment schedule using the performance-based payments (PBP) analysis tool. The PBP analysis tool is on the DPC website in the Cost, Pricing & Finance section, Performance Based Payments-Guide Book & Analysis Tool tab, at http://www.acq.osd.mil/dpap/cpic/cp/Performance_based_payments.html .

The contractor will contact the appropriate air carrier in advance to explain the particular circumstances and obtain instructions on the special screening procedures to follow when: (A) Routine processing would subject the classified material to compromise or damage. (B) Visual examination is or may be required to successfully screen a classified package. (C) Classified

material is in specialized containers, which due to its size, weight, or other physical characteristics cannot be routinely processed. (iii) Authorization letter. Contractors will provide employees with written authorization to hand carry classified material on commercial aircraft that includes: (printed page 83343) (A) Full name, date of birth, height, weight, and signature of the traveler and statement that he or she is authorized to transmit classified material. (B) Description of the type of identification the traveler will present on request. (C) Description of the material being hand carried, with a request that it be exempt from opening. (D) Identification of the points of departure, destination, and known transfer points. (E) Name, telephone number, and signature of the FSO, and the location and telephone number of the CSA. (6) Escorts. If an escort is necessary to ensure the protection of the classified information being transported, the contractor will assign a sufficient number to each classified shipment to ensure continuous surveillance and control over the shipment while in transit. The contractor will furnish escorts with specific written instructions and operating procedures prior to shipping that include: (i) Name and address of persons, including alternates, to whom the classified material is to be delivered. (ii) Receipting procedures. (iii) Means of transportation and the route to be used. (iv) Duties of each escort during movement, during stops en route, and during loading and unloading operations. (v) Emergency and communication procedures. (g) Destruction. Contractors will: (1) Destroy classified material in their possession based on the disposition instructions in the contract security classification specification or equivalent. (2) Follow the guidance for destruction of classified material in accordance with 32 CFR 2001.47 and the destruction equipment standards in accordance with 32 CFR 2001.42(b) . See <https://www.nsa.gov/resources/everyone/media-destruction/> and any CSA provided guidance for additional information. (h) Disclosure. Contractors will establish processes by which classified information is disclosed only to authorized persons. (1) Disclosure to employees. Contractors are authorized to disclose classified information to their cleared employees with the appropriate eligibility for access to classified information and need to know as necessary, including cleared employees across the MFO, when applicable, for the performance of tasks or services essential to the fulfillment of a classified contract or subcontract. (2) Disclosure to subcontractors. (i) Contractors:

rk Vulnerability Analysis,' in Proceedings of the ACM Conference on Computer and Communications Security , 2002. 11. R. Lippmann, K. Ingols, C. Scott, K. Piwowarski, K. Kratkiewicz, M. Artz, R. Cunningham, 'Validating and Restoring Defense in Depth Using Attack Graphs,' MILCOM Military Communications Conference, 2006. 12. S. Noel, J. Jajodia, 'Understanding Complex Network Attack Graphs through Clustered Adjacency Matrices,' in Proceedings of the 21 st Annual Computer Security Applications Conference , 2005. 13. S. Noel, S. Jajodia, 'Managing Attack Graph Complexity through Visual Hierarchical Aggregation,' in Proceedings of the ACM CCS Workshop on Visualization and Data Mining for Computer Security , 2004. 14. S. Noel, S. Jajodia, 'Advanced Vulnerability Analysis and Intrusion Detection through Predictive Attack Graphs,' Critical Issues in C4I, Armed Forces Communications and Electronics Association (AFCEA) Solutions Series, 2009. 15. S. Noel, S. Jajodia, 'Proactive Intrusion Prevention and Response via Attack Graphs,' in Practical Intrusion Detection , Ryan Trost (ed.), Addison-Wesley Professional, in preparation. 16. F. Cuppens, R. Ortalo, 'LAMBDA: A Language to Model a Database for Detection of Attacks,' in Proceedings of the Workshop on Recent Advances in Intrusion Detection , 2000.

Given the records access requirement, the records retention requirement in both the proposed and final rules may create a perverse incentive for entities to destroy records, even though we estimate that this incentive will lead to the actual destruction of very few records, and very small reductions in investigative speed. Private firms are quite reluctant to share their private records with outsiders such as federal regulatory agencies. Facilities may choose to destroy records once legal retention requirements have been met rather than risk the possibility of sharing them with FDA. Consequently, there is a nonzero probability that facilities will destroy records subject to the retention requirements shortly after the legal retention requirement has been met, and that those records would not exist in the event of an FDA records access request. The incentive to destroy records due to the access requirement will likely result in the destruction of a very small fraction of records because of the private utility from retaining records, and also the costs of destroying them. Because of the perverse nature of this incentive, it is informative to estimate its impact on the benefits from final rule-especially since the costs of the 1 and 2 years records retention provisions were estimated to be zero because the retention time periods are the same as or shorter than current business practices. We used outbreak investigation data to estimate the

reduction in benefits when retention requirements are redefined to be 6, 12, and 24 months based on NIST definitions of shelf lives. Investigations that remained open 6 months after initial exposure were considered possible candidates for continued investigative visits. From FDA investigation information, we estimated that about 20 percent of all FDA investigations from 2000 to 2003 remained open 6 months after initial exposure to the pathogen. However, it is likely that most of these investigations did not require access to a firm's records after 6 months. We assume that a maximum of 20 percent of all traceback investigations are candidates for a records access request 6 months after initial exposure to the pathogen. We assume that half of the investigative visits in one of these candidate investigations requires access to records after 6 months, and that 1/3 of these access requests are for records subject to the 6 month retention period (i.e., a 1/3 probability for 6 months, a 1/3 probability for 12 months and a 1/3 probability for 24 months). Consequently, 3.3 percent of records requests for records subject to the 6 month retention time are estimated to be made after 6 months (20 percent x 1/2 x 1/3).

3.1.13 Protocol Errors (CWE-254, CWE-573, CWE-668) Description Protocols are rules of communication.

capabilities required from IoT devices and their manufacturers, respectively, as well as associated documentation to round out the guidance provided by the program. The documents are complemented by an online catalog [CATALOG] of detailed technical capabilities and supporting non-technical capabilities, updates that were published in March of 2021. - Smart Door Lock: Federal organizations may utilize connected door locks that can scan PIV cards and manage access to and within facilities. - Unmanned Aircraft System (UAS): Federal organizations could use UAS to inspect facilities as part of monitoring and maintenance of the facility. - Water Sensors: Some federal organizations may use connected IoT environment sensors to monitor various aspects of facilities. Mr. Fagan concluded by briefly reviewing updates to the online IoT device cybersecurity capabilities catalog and encouraging workshop participants to provide input and feedback on the catalog's contents and utility.

.org/10.6028/NIST.SP.800-63-4 - [4] Temoshok D, Fenton JL, Choong YY, Lefkovitz N, Regenscheid A, Galluzzo R, Richer JP (2025) Digital Identity Guidelines: Authentication and Authenticator Management. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-63B-4. <https://doi.org/10.6028/NIST.SP.800-63B-4> - [5] Regenscheid A, Galluzzo R (2023) Phishing Resistance -Protecting the Keys to Your Kingdom. <https://www.nist.gov/blogs/cybersecurity-insights/phishing-resistanceprotecting-keys-your-kingdom> - [6] Cybersecurity and Infrastructure Security Agency (2025) List of Federal Financial Assistance Programs Funding Emergency Communications. <https://www.cisa.gov/safecom/emergency-comms-grants-list> - [7] Weston D (2024) Microsoft's guidance to help mitigate Kerberoasting. (Microsoft Corporation, Redmond, WA.) Available at <https://www.microsoft.com/enus/security/blog/2024/10/11/microsofts-guidance-to-help-mitigate-kerberoasting/> - [8] Fisher W, Russell M, Umarji S, Scarfone K (2021) Background on Identity Federation Technologies for the Public Safety Community. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Internal Report 8336. <https://doi.org/10.6028/NIST.IR.8336-draft> - [9] Grassi PA, Nadeau EM, Richer JP, Squire SK, Fenton JL, Lefkovitz NB, Danker JM, Choong Y-Y, Greene KK, Theofanos MF (2017) Digital Identity Guidelines: Federation and Assertions. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-63C, Includes updates as of March 02, 2020. <https://doi.org/10.6028/NIST.SP.800-63C>

any liability arising out of the performance of this contract, including costs and expenses, incurred as the result of the Contractor's potential or actual unauthorized disclosure of trade secrets, copyrighted materials, contractor bid or proposal information, source selection information, classified information, material marked as 'Controlled Unclassified Information', information subject to a right of privacy or publicity, personally identifiable information as defined by OMB Circular A-130 (2016) or successor thereof, or any record as defined in 5 U.S.C. 552a . (3) In the event of any claim or suit against the Government on account of any alleged unauthorized disclosure or introduction of data or information arising out of the performance of this contract or services performed under this contract, the Contractor shall furnish to the Government, when requested by the Contracting Officer, all evidence and information in the Contractor's possession pertaining to such claim or suit. (4) The provisions of this paragraph (h) do not apply unless the Government provides notice to the Contractor as soon as practicable of any

claim or suit, affords the Contractor an opportunity under applicable laws, rules, or regulations to participate in the defense of the claim or suit, and these provisions do not apply to any libelous or other unlawful matter contained in such data furnished to the Contractor by the Government and incorporated in data to which this clause applies. Further, this indemnity shall not apply to-

- (i) A disclosure or inclusion of data or information upon specific written instructions of the Contracting Officer directing the disclosure or inclusion of such information or data;
- (ii) A third-party claim that is unreasonably settled without the consent of the Contractor, unless required by final decree of a court of competent jurisdiction.

(i) Subcontracts. The Contractor shall include the substance of this clause, including this paragraph (i), in all subcontracts under this contract for services to develop, implement, operate, or maintain a FIS using cloud computing services. (End of clause) 52.239-YY Federal Information Systems Using Non-Cloud Computing Services. As prescribed in 39.X04(a) insert the following clause: Federal Information Systems Using Non-Cloud Computing Services (DATE) (a) Definitions. As used in this clause-

Cloud computing means a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. Cloud computing is characterized by on-demand self-service, broad network access, resource pooling, rapid elasticity, and measured service; and includes service models such as software-as-a-service, infrastructure-as-a-service, and platform-as-a-service (NIST SP 800-145).
Component

Inventors, reviewers, evaluators, officials of U.S. and foreign patent offices, and other persons having a direct interest in the file. Exemptions claimed for the system: None. Appendix F to Part 310-Format for New or Altered System Report (See paragraph (c) of §-310.33) The report on a new or altered system shall consist of a transmittal letter, a narrative statement, and include supporting documentation.

A. Transmittal Letter The transmittal letter shall be prepared by the Defense Privacy Office and shall contain assurances that the new or altered system does not duplicate any existing Component systems, DoD-wide systems or government-wide systems. The narrative statement, and the system notice, shall be attached thereto.

B. Narrative Statement The statement shall include information on the following:

1. System Identifier and name;
2. Responsible official;
3. Purpose of establishing the system [for a new system only] or Nature of the changes proposed for the system [for altered system only];
4. Authority for maintenance of the System;
5. Probable or potential effects on the privacy of individuals;
6. Is the system, in whole or part, being maintained by a contractor;
7. Steps taken to minimize risk of unauthorized access;
8. Routine use compatibility;
9. OMB information collection requirements; and
10. Supporting documentation.

Attachment 1-Sample Format for Narrative Statement DEPARTMENT OF DEFENSE [Component Name]
Narrative Statement on a [New/Altered] System of Records Under the Privacy Act of 1974

1. System Identifier and Name. This caption sets forth the identification and name of the system (see subparagraphs (b)((c) of §-310.32).
2. Responsible Official. The name, title, address, and telephone number of the official responsible for the report and to whom inquiries and comments about the report may be directed by Congress, the Office of Management and Budget, or the Defense Privacy Office.
3. Purpose of establishing the system or nature of the changes proposed for the system: Describe the purpose of the new system or how an existing system is being changed.
4. Authority for maintenance of the system. See paragraph (g) of §-310.32.
5. Probable or potential effects on the privacy of individuals. What effect, if any, will the new or altered system impact the personal privacy of the affected individuals.
6. Is the system, in whole or in part, being maintained by a contractor. If yes, Components shall ensure that the contract has incorporated the Federal Acquisition privacy clause (see paragraph (a)(1) of §-310.12).
7. Steps taken to minimize risk of unauthorized access. Describe actions taken to reduce the vulnerability of the system to potential threats. See Appendix A to this part.
8. Routine use compatibility. Provide assurances that any records contained in the system that are disclosed outside the DoD shall be for a use that is compatible with the purpose for which the record was collected. Advise whether or not the blanket routine uses apply to this system.
- 9.

emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866 , Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804 . V. Executive Order 13771 This rule is not subject to E.O. 13771 , Reducing Regulation and Controlling Regulatory Costs, because this rule is not a significant regulatory action under E.O. 12866 . VI. Regulatory

Flexibility Act DoD, GSA, and NASA have prepared a Final Regulatory Flexibility Analysis (FRFA) consistent with the Regulatory Flexibility Act, 5 U.S.C. 601 , et seq. The FRFA is summarized as follows: This final rule is to revise the FAR to update and clarify the requirements for using the DD Form 254, Contract Security Classification Specification. The Government uses the DD Form 254 to convey security requirements to contractors when contract performance requires access to classified information. Prime contractors also use the DD Form 254 to convey security requirements to subcontractors that require access to classified information to perform on a subcontract. Subcontractors may also use the DD Form 254 if access to classified information is required to convey security requirements to additional subcontractors. There were no significant issues raised by the public comments in response to the initial regulatory flexibility analysis. The final rule will apply to small businesses awarded contracts or subcontracts by Executive agencies covered by the National Industrial Security Program that require access to classified information. Currently, the Defense Security Service monitors approximately 13,500 contractor facilities that are cleared for access to classified information. Approximately 9,000 facilities are considered less-complex, which includes small businesses and smaller security operations. Subject matter experts estimate that 5,400 (60 percent) of the 9,000 less-complex facilities are small businesses. The final rule does not impose any Paperwork Reduction Act reporting, recordkeeping, or other compliance requirements on any small entities. The rule does not impose any new reporting, recordkeeping or other compliance requirements. The rule does not duplicate, overlap, or conflict with any other Federal rules. DoD, GSA, and NASA were unable to identify any alternatives to the rule which would reduce the impact on small entities and still meet the requirements of the rule. Interested parties may obtain a copy of the FRFA from the Regulatory Secretariat Division. The Regulatory Secretariat Division has submitted a copy of the FRFA to the Chief Counsel for Advocacy of the Small Business Administration. VII. Paperwork Reduction Act The Paperwork Reduction Act (44 U.S.C. chapter 35) applies; however, the changes to the FAR do not impose (printed page 40063)

(viii)(A) When procuring supplies or services, the contracting officer shall ensure Supplier Performance Risk System (SPRS) assessments of price risk and supplier risk are considered as a part of the award decision. See 204.7603. (B) When procuring an end product identified by a material identifier that is available as described at PGI 204.7603, the contracting officer shall also consider SPRS assessments of item risk in the award decision. 10. Amend section 215.404-1 by adding paragraph (b)(viii) to read as follows: 215.404-1 Proposal analysis techniques. * * * * *

* (b) * * * (viii) When procuring a service or an end product identified by a material identifier that is available as described at PGI 204.7603, the contracting officer shall consider the Supplier Performance Risk System price risk assessments in determining if a proposed price is consistent with historical prices paid for an item or otherwise creates a risk to the Government. See also 215.403-3(a)(1). * * * * *

PART 216. TYPES OF CONTRACTS 11. Amend section 216.505 by adding paragraph (a)(S-71) to read as follows: 216.505 Ordering. (a) * * * (S-71) See 204.7603 for procedures on the required use of the Supplier Performance Risk System (SPRS) risk assessments. (i) The contracting officer shall ensure SPRS assessments of price risk and supplier risk are considered as a part of the award decision. (ii) When placing an order for an end product identified by a material identifier that is available as described at PGI 204.7603, and item risk was not previously considered during award of the contract, the contracting officer shall also consider SPRS assessments of item risk in the award decision. (iii) Use the provision at 252.204-7024, Notice on the Use of the Supplier Performance Risk System, as prescribed in 204.7604 to the extent permitted by the contract. * * * * *

PART 252. SOLICITATION PROVISIONS AND CONTRACT CLAUSES 12. Add section 252.204-7024 to read as follows: 252.204-7024 Notice on the Use of the Supplier Performance Risk System. As prescribed in 204.7604, use the following provision: Notice on the Use of the Supplier Performance Risk System (Mar 2023) (a) Definitions. As used in this provision-

Item risk means the probability that a product, based on intended use, will introduce performance risk resulting in safety issues, mission degradation, or monetary loss. Price risk means a measure of whether a proposed price for a product or service is consistent with historical prices paid for that item or service. Supplier risk means the probability that an award may subject the procurement to the risk of unsuccessful performance or to supply chain risk (see Defense Federal Acquisition Regulation Supplement 239.7301). (b) The Supplier Performance Risk System (SPRS), available at <https://piee.eb.mil/> , will be used in the evaluation of the Quoter or Offeror's performance. SPRS retrieves item, price, quality, delivery, and contractor information on contracts from Government (printed page 17340)

(Comment 1) Some comments state that it would be beneficial for the agency to provide the food

industry with a model form that could be used to record all the required information, with the option for the industry to use this form or established recordkeeping systems. One comment requests that the agency develop and provide respective freeware that could be available as a compact disc (CD) or downloaded from the FDA Web site well in advance of the compliance date of the final rule. A few comments request that the regulations make clear that the model form is guidance and is not mandatory. One comment suggests that as a way to show that the model form is guidance, the agency should place the model form in an appendix to the regulations. Several comments object to the inclusion of a model form in the regulations. The comments oppose using any one-size fits all generic form as an example or requirement. The comments suggest that affected businesses should decide the format in which the required records should be kept as dictated by specific business practices. The comments express concern that example forms might become informal requirements out in the field even though originally only meant as guidance. One comment recommends that the agency provide further examples of (printed page 71566) scenarios, rather than model forms, where records would be in compliance and noncompliance with the final regulations. In addition, several comments state that most food companies currently maintain the chain-of-distribution information that is required by these regulations. However, the diversity and complexity of the food industry means that the information is maintained in many different ways and formats, ranging from computerized records systems to file folders of paper records. The recordkeeping systems are designed to provide the necessary information to remove food from the market and prevent more food presenting the same risk from entering the market. The comments state that the regulations should not prescribe any specific manner or form of maintaining the information.

- Collaboration with JTF partners and other federal organizations: CSD staff worked closely with JTF partners on continued cooperation and planning to ensure that the five JTF publications remain current, and on the designation of additional special publications as JTF guidance. The CSD FISMA implementation project staff also collaborated with DOD, IC, the Department of Homeland Security (DHS), the Federal Emergency Management Agency (FEMA), the Government Accountability Office (GAO), OMB, GSA, the Small Business Administration (SBA), and the Inspector Generals (IGs) on multiple projects to ensure consistency with FISMA-related guidance and to protect information in a way that is commensurate with risk. In the past year, NIST continued to support the EAC in finalizing changes to the Voluntary Voting System Guidelines (VVSG) 1.1. These changes sought to improve the auditability of voting systems, provide greater software integrity protections, expand and improve access-control requirements, and help ensure that cryptographic security mechanisms are implemented properly. The EAC approved these updates to the VVSG in March 2015. In addition, NIST completed a set of draft test assertions for the security requirements in the VVSG. This included test assertions in the Services' (DHHS) Office for Civil Rights (OCR) co-hosted the eighth annual Health Insurance Portability and Accountability Act (HIPAA) Security Rule conference, Safeguarding Health Information: Building Assurance through HIPAA Security, in September 2015 in Washington, D.C. The conference offered important sessions that focused on broad topics of interest to the healthcare and health IT security community.

(Comment 48) One comment states it appears that rather than exempting convenience stores that sell food for immediate consumption, FDA has proposed a partial exemption such that records need be kept only for the nonexempt activities, but that is not clear in the proposed rule. FDA should either take a functional approach that allows facilities that sell food to consumers for immediate consumption to have a full exemption, or FDA should clarify that convenience stores and other facilities that make sales for immediate consumption need not maintain records for that part of their operation. (Response) Convenience stores and other covered facilities that sell to consumers are an example of a mixed-type facility. Food that the convenience store prepares and sells directly to consumers for immediate consumption (i.e., hot dogs, hot pretzels), is exempt from subpart J of this final rule under the restaurant exemption. Under § 1.337 of this final rule, the facility is required to keep records of the nontransporter and transporter immediate previous sources for all other food. The facility is not required to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients for sales of food to consumers, but must establish and maintain records to identify immediate subsequent recipients of food who are not consumers, as required by § 1.345 of this final rule, when such information is reasonably available, as discussed in response to comment 38. In addition, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements of subpart J in this final rule, except the record access provisions for existing records under §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this

exclusion.) (Comment 49) Some comments state they are engaged in marketing products directly to the consumer through direct sales, mail order, Internet sales, and/or retail sales and urge FDA to clarify the scope of 'retail facilities' to include independent distributors in direct sales forces, mail order companies, or Internet sales operations, because it is apparent that neither Congress nor FDA intended for the recordkeeping requirement to encompass records of individual sales to consumers.

One commenter objected to CMMC level 1 annual affirmation, which they considered an unwarranted expansion of CUI safeguarding requirements to information systems that process only FCI. One commenter recommended revisions to explicitly indicate that OSAs may choose to engage the services of a C3PAO to inform the OSA's Level 1 self-assessment submission. Another commenter recommended editorial revisions to avoid use of the term 'CMMC security requirements' based on the observation that CMMC requirements are aligned directly to those identified in FAR clause 52.204-21 or NIST publications. One commenter asked for explanation of perceived differences between tables in the published rule that map CMMC Level 1 Security Requirements to NIST SP 800-171A Jun2018, as compared with prior versions of the document. One commenter asked for the rationale associated with mapping 15 requirements for CMMC level 1 to 17 requirements in CMMC level 2. Two commenters asked if systems that process FCI (and require CMMC level 1) are considered within scope for CMMC level 2 or 3 assessments, and if so, how they should be documented. Response: When applicable, the DoD does require an annual CMMC Level 1 self-assessment against the 15 safeguarding requirements aligned with FAR clause 52.204-21. Annual affirmations are required at every CMMC level. There are no explicit documentation requirements for a CMMC Level 1 Self-Assessment. The DoD modified the Level 1 Scoping Guide to provide clarity. An OSA may complete as many self-assessments as desired, and there is no required timeframe between Level 1 self-assessments and updating CMMC Status in SPRS. The entry in SPRS for CMMC Level 1 is a binary selection between Yes and No based on meeting all Level 1 security requirements. The CMMC Program verifies implementation of security requirements for FCI in accordance with FAR clause 52.204-21. The DoD has elected to use the CMMC Status postings and attestations in SPRS as the mechanism to verify compliance with applicable CMMC requirements. An OSA engaging an authorized C3PAO to perform the Level 1 self-assessment and then using the resulting CMMC Status when 'self-assessing' is permissible. The OSA however retains all the responsibilities and liabilities of the affirmation. No revisions to the rule were necessary. Writing style recommendations were not incorporated and no responses were provided to those comments based on comparison of pre-publication draft versions with those officially published for public comment. DoD aligned the security requirements for Level 1 exactly with those in FAR clause 52.204-21 and aligned the security requirements in Level 2 exactly with those in NIST SP 800-171 R2. The 15 security requirements in FAR clause 52.204-21, which make up CMMC Level 1, were mapped by NIST into 17 security requirements in NIST SP 800-171 R2. This was accomplished by splitting 1 requirement into 3 parts, while the other 14 align. Table 2 to § 170.15(c)(1)(ii) provides a mapping.

From the NIST SP 800-172 Rev 3 Final Public Draft: Platforms include operating systems, the NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 underlying computer architectures, or both. Platform-independent applications are 1874

ory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. Organizations are encouraged to review all draft publications during public comment periods and provide feedback to NIST. Many NIST cybersecurity publications, other than the ones noted above, are available at <https://csrc.nist.gov/publications>.
Comments on this publication may be submitted to: National Institute of Standards and Technology Attn: Applied Cybersecurity Division, Information Technology Laboratory 100 Bureau Drive (Mail Stop 2000) Gaithersburg, MD 20899-2000 Email: iotsecurity@nist.gov All comments are subject to release under the Freedom of Information Act (FOIA). ## Reports on Computer Systems Technology The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and

privacy of other than national security-related information in federal information systems. ##
Abstract This report provides a summary of the discussion and findings from the NIST Cybersecurity
Risks in Consumer Home Internet of Things (IoT) Devices virtual workshop in October 2020.

21 CFR part 123) should be sufficient and deemed adequate to meet the requirements under the Bioterrorism Act and that FDA should not introduce additional, stand alone, recordkeeping systems. (Response) As discussed in response to comment 79, § 1.330 of the final regulation states that duplication of existing records is not required if those records contain all of the information required by subpart J of this final rule. That includes records kept under the regulations identified in the comment. (Comment 85) One comment states that it would be beneficial if FDA announced the suitability of records kept under existing requirements well ahead of the implementation deadline under the Bioterrorism Act. (Response) FDA is not able to determine what records currently exist throughout the entire food industry that satisfy these regulations due to the diversity and complexity of the food industry and the various existing Federal, State, and local regulations that require recordkeeping, as well as varying business practices. The person subject to these regulations is responsible for ensuring that it keeps all applicable records and that those records are available to FDA under the record availability requirements in § 1.361 of this final rule. FDA points out that the earliest compliance date of this final rule is December 9, 2005, and that many persons are not required to comply with this final rule for up to 2 years after publication. Therefore, FDA believes that it has provided sufficient time for persons to determine what, if any, additional information must be kept to comply with these provisions well ahead of the compliance date of this final rule. (Comment 86) A few comments note that most food companies currently maintain the chain of distribution information that FDA proposed, but the diversity and complexity of the food industry means that the information is maintained in many different ways and formats, ranging from computerized records systems to file folders of paper records. The comments state that it should be of no concern to FDA and, therefore, not the subject of the regulations to prescribe any specific manner or form of maintaining the information. (Response) As discussed in response to comments 1 and 83 of this document and in the proposed rule, FDA's intent is to have as little impact as possible on current recordkeeping practices if those records can meet the requirements of these regulations. FDA is requiring specific information be kept by a covered person, but not specifying the form or type of system in which those records must be maintained. The person subject to these regulations is responsible for ensuring that it keeps all applicable records and that those records be made available to FDA under the record availability requirements in § 1.361 of this final rule. To satisfy the requirements in this final rule, paper or electronic records or a combination of the two may be used.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense General Services Administration National Aeronautics and Space Administration 48 CFR Parts 1, 2, 3, 4, 5, 7, 9, 11, 12, 15, 27, 33, 42, 52, and 53 [FAR Case 2017-016, Docket No. 2017-0016, Sequence No. 1] RIN 9000-AN56 AGENCY: Department of Defense (DoD), General Services Administration (GSA), and National Aeronautics and Space Administration (NASA). ACTION: Proposed rule. SUMMARY: DoD, GSA, and NASA are proposing to amend the Federal Acquisition Regulation (FAR) to implement the National Archives and Records Administration's Controlled Unclassified Information Program enacted under an Executive Order entitled Controlled Unclassified Information. DATES: Interested parties should submit written comments to the Regulatory Secretariat Division at the address shown below on or before March 17, 2025 to be considered in the formation of the final rule. ADDRESSES: Submit comments in response to FAR Case 2017-016 to the Federal eRulemaking portal at <https://www.regulations.gov> by searching for 'FAR Case 2017-016'. Select the link 'Comment Now' that corresponds with 'FAR Case 2017-016'. Follow the instructions provided on the 'Comment Now' screen. Please include your name, company name (if any), and 'FAR Case 2017-016' on your attached document. If your comment cannot be submitted using <https://www.regulations.gov>, call or email the points of contact in the FOR FURTHER INFORMATION CONTACT section of this document for alternate instructions. Instructions: Please submit comments only and cite 'FAR Case 2017-016' in all correspondence related to this case. Public comments may be submitted as an individual, as an organization, or anonymously (see frequently asked questions at <https://www.regulations.gov/faq>). Comments submitted in response to this rule will be made

publicly available and are subject to disclosure under the Freedom of Information Act. For this reason, please do not include in your comments information of a confidential nature, such as sensitive personal information or proprietary information, or any information that you would not want publicly disclosed unless you follow the instructions below for confidential comments. Summary information of the public comments received, including any specific comments, will be posted on <https://www.regulations.gov>.

Classified sessions will be held only at a USG installation or a cleared contractor facility where adequate physical security and procedural controls have been approved. The authorizing USG agency is responsible for evaluating and approving the location proposed for the meeting. (4) Security arrangements for meetings. The contractor will develop the security measures and procedures to be used and obtain the authorizing agency's approval. The security arrangements must provide: (i) Announcements. Approval of the authorizing agency will be obtained for all announcements of the meeting. (A) Announcements will be unclassified and will be limited to a general description of topics expected to be presented, names of speakers, and administrative instructions for requesting invitations or participation. Classified presentations will not be solicited in the announcement. (B) When the meeting has been approved, announcements may only state that the USG agency has authorized the conduct of classified sessions and will provide necessary security assistance. (C) The announcement will further specify that security clearances and justification to attend classified sessions are to be forwarded to the authorizing agency or its designee. (D) Invitations to foreign persons will be sent by the authorizing USG agency. (ii) Clearance and need-to-know. All persons in attendance at classified sessions will possess the requisite clearance and need-to-know for the information to be disclosed. (A) Need-to-know will be determined by the authorizing agency or its designee based on the justification provided. (B) Attendance will be authorized only to those persons whose security clearance and justification for attendance have been verified by the security officer of the organization represented. (C) The names of all authorized attendees or participants must appear on an access list with entry permitted to the classified session only after verification of the attendee's identity based on presentation of official photographic identification such as a passport, contractor or USG identification card. (iii) Presentations. Classified information must be authorized for disclosure in advance by the USG agency having jurisdiction over the information to be presented. (A) Individuals making presentations at meetings will provide sufficient classification guidance to enable attendees to identify what information is classified and the level of classification. (B) Classified presentations will be delivered orally or visually. (C) Copies of classified presentation materials will not be distributed at the classified meeting, and any classified notes or electronic recordings of classified presentations will be classified, safeguarded, and transmitted as required by this rule. (iv) Physical security.

) on behalf of the DoD. The OSC must complete and achieve a MET result for all security requirements specified in table 1 to § 170.14(c)(4) to achieve the CMMC Status of Level 3 (DIBCAC). DCMA DIBCAC will submit the Level 3 certification assessment results into the CMMC instantiation of eMASS, which then provides automated transmission to SPRS. To maintain compliance with the requirements for a CMMC Status of Level 3 (DIBCAC), the Level 3 certification assessment must be performed every three years for all information systems within the Level 3 CMMC Assessment Scope. In addition, given that compliance with Level 2 requirements is a prerequisite for applying for CMMC Level 3, a Level 2 (C3PAO) certification assessment must also be conducted every three years to maintain CMMC Level 3 (DIBCAC) status. Level 3 certification assessment must be completed within three years of the CMMC Status Date associated with the Final Level 3 (DIBCAC) or, if there was a POA&M, then within three years of the CMMC Status Date associated with the Conditional Level 3 (DIBCAC). (i) Inputs into the CMMC instantiation of eMASS. The Level 3 certification assessment results input into the CMMC instantiation of eMASS shall include, at minimum, the following items: (A) Date and level of the assessment. (B) For each Assessor(s) conducting the assessment, name and government organization information. (C) All industry CAGE code(s) associated with the information system(s) addressed by the CMMC Assessment Scope. (D) The name, date, and version of the system security plan(s) (SSP). (E) CMMC Status Date. (F) Result for each security requirement objective. (G) POA&M usage and compliance, as applicable. (H) List of the artifact names, the return value of the hashing algorithm, and the hashing algorithm used. (ii) Conditional Level 3 (DIBCAC). The OSC has achieved the CMMC Status of Conditional Level 3 (DIBCAC) if the Level 3 certification assessment results in a POA&M and the POA&M meets all CMMC Level 3 POA&M requirements listed in § 170.21(a)(3). (A) Plan of Action and Milestones. A Level 3 POA&M is allowed only in accordance with the CMMC POA&M requirements listed in § 170.21. (B) POA&M closeout. The OSC must remediate any NOT MET

requirements, must undergo a POA&M closeout certification assessment from DCMA DIBCAC, and DCMA DIBCAC must post compliance results into the CMMC instantiation of eMASS within 180 days of the CMMC Status Date associated with the Conditional Level 3 (DIBCAC). If the POA&M is not successfully closed out within the 180-day timeframe, the Conditional Level 3 (DIBCAC) CMMC Status for the information system will expire. If Conditional Level 3 (DIBCAC) CMMC Status expires within the period of performance of a contract, standard contractual remedies will apply, and the OSC will be ineligible for additional awards with a requirement for the CMMC Status of Level 3 (DIBCAC) for the information system within the CMMC Assessment Scope until such time as a new CMMC Status is achieved.

DoD does not agree with a commentor's statement that Specialized Assets are not actually assessed against CMMC security requirements. As documented in § 170.19, Specialized Assets are identified by the OSC. Assessment requirements of Specialized Assets differ between CMMC Level 2 and CMMC Level 3. If Specialized Assets are part of a CMMC Level 2 assessment, the OSA must document them in the asset inventory, document them in the SSP, and show how these assets are managed using the contractor's risk-based security policies, procedures, and practices. If Specialized Assets are part of a CMMC Level 3 assessment, they must be assessed against all CMMC Level 2 security requirements and CMMC Level 3 security requirements, identified in § 170.14(c)(4). DoD agrees with one comment that even if NIST SP 800-171 R2 cannot be implemented, that does not mean the Specialized Assets cannot be secured. CMMC requirements are defined to align directly to NIST SP 800-171 R2 and NIST SP 800-172 Feb2021 requirements. For additional ease of burden, at Level 1, IoT and OT are not in scope, at Level 2 there are reduced requirements, but they become in-scope at Level 3, unless they are physically or logically isolated. DoD has reviewed the text and declines to change the definition of Out-of-scope assets because CUI should not (printed page 83140) be transmitted via clear-text per NIST SP 800-171 R2. The DoD has reviewed the suggested changes to asset categories and scoping tables and declines to make an update. The asset categories in the rule help the OSA understand the requirements of various asset types that might be found within the assessment boundary. OSAs determine the asset categories and assessment scope based on how and where they will process, store, and transmit FCI and CUI. DoD cannot comment on the suitability of any specific approach or technology to successfully implement CMMC security requirements.

b. Virtual Desktop Infrastructure
Comment: Several comments requested clarification on the use of Virtual Desktop Infrastructures and how to scope its components. Response: The rule has been updated in table 3 to § 170.19(c)(1) and table 5 to § 170.19(d)(1) to state that an endpoint hosting a VDI client configured to not allow any processing, storage, or transmission of FCI and CUI beyond the Keyboard/Video/Mouse sent to the VDI client is considered out of scope.

c. Contractor Risk Managed Assets
Comment:

(2) In all orders and blanket purchase agreements involving the development or delivery of any information technology, whether acquired as a service or as a supply, consider the need for an evaluation factor regarding supply chain risk (see subpart 239.73). PART 212-ACQUISITION OF COMMERCIAL ITEMS 4. Amend section 212.301 by:

a. Revising paragraph (f)(xiv);

b. Redesignating:

i. Paragraphs (f)(liii) through (f)(lxv) as (f)(lvi) through (f)(lxvii); and

ii. Paragraphs (f)(lxv) through (f)(liii) as (f)(lxvi) through (f)(liii).

c. Adding new paragraphs (f)(xv), (f)(liv), and (f)(lv). Revision and additions to read as follows:

212.301 Solicitation provisions and contract clauses for the acquisition of commercial items.

(f) * * * (xiv) Use the provision 252.215-7008, Only One Offer, as prescribed at 215.408(4); (xv) Use the clause at 252.219-7003, Small Business Subcontracting Plan (DoD Contracts), as prescribed in 219.708(b)(1)(A)(1), to comply with 15 U.S.C. 637 . Use the clause with its Alternate I when prescribed in 219.708(b)(1)(A)(2). * * *

* * * (liv) Use the provision at 252.239-7017, Notice of Supply Chain Risk, as prescribed in 239.7306(a), to comply with section 806 of Public Law 111-383 , in all solicitations for contracts involving the development or delivery of any information technology, whether acquired as a service or as a supply. (lv) Use the clause at 252.239-7018, Supply Chain Risk, as prescribed in 239.7306(b), to comply with section 806 of Public Law 111-383 , in all solicitations and contracts involving the development or delivery of any information technology, whether acquired as a service or as a supply. * * * * *

PART 215-CONTRACTING BY NEGOTIATION 5. Amend section 215.304 by adding new paragraph (c)(v) to read as follows:

215.304 Evaluation factors and significant subfactors. (c) * * * (v) In all solicitations and contracts involving the development or delivery of any information technology, whether acquired as a service or as a supply, consider the need for an evaluation factor regarding supply chain risk (see subpart 239.73).

6. Add new subpart 215.5 to read as follows:

Subpart 215.5-Preaward, Award, and Postaward Notifications, Protests, and Mistakes

215.503 Notifications to unsuccessful offerors. 215.506 Postaward debriefing of offerors.

Subpart 215.5-Preaward, Award, and Postaward Notifications, Protests, and Mistakes 215.503 Notifications to unsuccessful offerors. If the Government exercises the authority provided in 239.7305(d), the notifications to unsuccessful offerors, either preaward or postaward, shall not reveal any information that is determined to be withheld from disclosure in accordance with section 806 of the National Defense Authorization Act for Fiscal Year 2011, as amended by section 806 of the (printed page 69271) National Defense Authorization Act for Fiscal Year 2013 (see subpart 239.73). 215.506 Postaward debriefing of offerors.

| 3.11.6e | ENHANCED SECURITY REQUIREMENT Assess, respond to, and monitor supply chain risks associated with organizational systems and system components. | ENHANCED SECURITY REQUIREMENT Assess, respond to, and monitor supply chain risks associated with organizational systems and system components.

- What processes and assets require PNT data (direct recipients of PNT services)? - What processes and assets are dependent on other assets that require PNT data (i.e., what are the secondary effects)? - What processes and assets are vulnerable to the disruption or manipulation of PNT services? - What are the integrity and availability thresholds of PNT to avoid mission impact? - What safeguards are available? - What is the impact to the organization should a process or asset be lost or degraded? - What techniques can be used to detect events of concern? - What techniques can be used to respond to events of concern? - What techniques can be used to recover pre-event capabilities?

(A) To protect ongoing investigations and to protect from access criminal investigation information contained in this record system, so as not to jeopardize any subsequent judicial or administrative process taken as a result of information contained in the file. (B) From subsection (c)(3) because the release of the disclosure accounting, for disclosures pursuant to the routine uses published for this system, would permit the subject criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (C) From subsection (c)(4) because an exemption is being claimed for subsection this subsection will not be applicable. (D) From subsection (d) because access the records contained in this system would inform the subject of an investigation of existence of that investigation, provide subject of the investigation with information that might enable him to avoid detection, and would present a serious impediment to law enforcement. (E) From subsection (e)(4)(H) because system of records is exempt from individual access pursuant to subsection (j) of the Privacy Act of 1974. (F) From subsection (f) because this system of records has been exempted from access provisions of subsection (d). (5) System identifier and name. F031 AF SF A, Correction and Rehabilitation Records. (i) Exemption. Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if information is compiled and maintained by a component of the agency which performs as its principle function any activity pertaining to the enforcement of criminal laws. Portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(j) (2) from the following subsections of 5 U.S.C. 552a(c)(3) , (c)(4), (d), (e)(3), (e)(4)(G), (H) and (I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting, for disclosures pursuant to the routine uses published for this system, would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (c)(4) because an exemption is being claimed for subsection (d), this subsection will not be applicable. (C) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence (printed page 14737) of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement.

IBM Secure Execution for Linux is a hardware-based security technology that is built into the IBM z15T and LinuxONE III generation systems. It is designed to provide scalable isolation for individual workloads to help protect them from not only external attacks but also insider threats. Secure Execution provides isolation between a kernel-based VM (KVM) hypervisor host and guests in virtual environments. This level of vertical isolation is designed to remove the ability for administrators to have total visibility into the sensitive workloads being hosted on VMs and individual containers. Secure Execution provides hardened access restrictions to protect intellectual property and proprietary secrets while allowing administrators to manage and deploy

workloads as black boxes and continue normal job functions. Secure Execution also helps enterprises provide isolation between individual multi-tenant workloads running on a shared logical partition. Details of IBM Secure Execution for Linux can be found in [81].

The CMMC Assessment Process (CAP) v2.0, published by the Cyber AB in December 2024, is the official procedural guide for C3PAOs conducting CMMC Level 2 certification assessments. The CAP defines: 1. **Pre-assessment activities**: Scoping, scheduling, assessment team composition 2. **Assessment execution**: Evidence collection, interviews, technical testing across all 110 requirements 3. **Scoring methodology**: MET, NOT MET, NOT APPLICABLE for each requirement 4. **Reporting**: Assessment report format, findings documentation 5. **Certification recommendation**: Conditional or final certification criteria 6. **Closeout**: POA&M remediation verification within 180 days The CAP ensures consistency across all C3PAO assessments and provides organizations with a clear understanding of what to expect during a CMMC Level 2 assessment.

Paragraph (d) of the new clause 52.239-YY requires a contractor that develops, implements, operates, or maintains a FIS using non-cloud computing services and that FIS is designated as a moderate or high FIPS Publication 199 impact, to perform an annual, independent assessment of the security of each FIS, which includes an architectural review and penetration testing of the FIS. The contractor must also conduct, at least annually, cyber threat hunting and vulnerability assessment to search for cybersecurity risks, vulnerabilities, and indicators of compromise. Contractors are required to provide the contracting officer with the results of both assessments, including any recommended improvements or risk mitigations identified for the FIS. If the Government chooses not to require the contractor to implement a recommended improvement or risk mitigation and provides the contractor with a rationale for not implementing the recommendation, the contractor is required to document the Government's rationale for not implementing the recommendation in the contractor's system security plan. Of the 140 non-cloud FISs currently being operated or maintained by contractors on behalf of the Government, the Government estimates that approximately 95 percent of those systems are designated as moderate or high FIPS 199 impacts. Applying that percentage to the estimated number of contractors annually awarded a contract to develop, implement, operate, or maintain a non-cloud FIS, it is estimated that 27 contractors (95 percent * 28 contractors) will be subject to the annual assessment requirements. Based on the discussion in paragraphs IV.B.3.i. through IV.B.3.iii. below, the total annual estimated cost for 27 contractors that operate or maintain a non-cloud FIS designated as a moderate or high FIPS 199 impact to comply with the annual assessment requirements of the rule is approximately \$6.6 million (27 contractors * (\$112,000 + \$132,000 + \$182)). The cost of the annual assessments accounts for the time it takes contractors to prepare for, conduct, document, review, and submit an assessment. i. Annual Independent Architectural Review and Penetration Test. This annual assessment includes an architectural review of the FIS, as well as penetration testing of the system. Based on the input of subject matter experts, the Government estimates the annual cost for a contractor to obtain an independent security assessment and architectural review of a FIS is approximately \$52,000. The Government estimates that four senior level employees will expend a total of 320 hours (4 individuals * 8 hours * 10 days) to complete the penetration testing of a FIS. According to subject matter experts, the average loaded wage rate of for a penetration tester is \$250.00. The Government estimates the annual cost for a contractor to obtain independent penetration testing of a FIS is \$80,000 (320 hours * \$250).

MA.L2-3.7.5 · Nonlocal Maintenance CMMC Assessment Guide · Level 2 | Version 2.13 153 FURTHER DISCUSSION Nonlocal maintenance activities must use multifactor authentication. Multifactor authentication requires at least two factors, such as: · something you know (e.g., password, personal identification number [PIN]); · something you have (e.g., cryptographic identification device, token); or · something you are (e.g., biometric fingerprint or facial scan). Requiring two or more factors to prove your identity increases the security of the connection. Nonlocal maintenance activities are activities conducted from external network connections such as over the internet. After nonlocal maintenance activities are complete, shut down the external network connection. This requirement, MA.L2-3.7.5 specifies the addition of multifactor authentication for remote maintenance sessions and complements five other requirements dealing with remote access (AC.L2-3.1.12, AC.L2-3.1.14, AC.L2-3.1.13, AC.L2-3.1.15, and IA.L2-3.5.3): · AC.L2-3.1.12 requires the control of remote access sessions. · AC.L2-3.1.14 limits remote access to specific access control points. · AC.L2-3.1.13 requires the use of cryptographic mechanisms when enabling remote sessions. · AC.L2-3.1.15 requires authorization for privileged commands executed during a remote session. · Finally, IA.L2-3.5.3 requires multifactor authentication for network access to non-

privileged accounts. Example You are responsible for maintaining your company's firewall. In order to conduct maintenance while working remotely, you connect to the firewall's management interface and log in using administrator credentials. The firewall then sends a verification request to the multifactor authentication app on your smartphone [a]. You need both of these things to prove your identity [a]. After you respond to the multifactor challenge, you have access to the maintenance interface. When you finish your activities, you shut down the remote connection by logging out and quitting your web browser [b]. Potential Assessment Considerations · Is multifactor authentication required prior to maintenance of a system when connecting remotely from outside the system boundary [a]? · Are personnel required to manually terminate remote maintenance sessions established via external network connections when maintenance is complete, or are connections terminated automatically through system session management mechanisms [b]?

labor hour estimates for authorized or certified assessors to work with the business to conduct the actual assessment Assessment Costs broken down into phases Phase 1: Planning and preparing for the assessment Phase 2: Conducting the assessment (self or C3PAO) Phase 3: Reporting of Assessment Results Phase 4: POA&M Closeout (for CMMC Level 3 only, if applicable and allowed) CMMC allows a limited open Plan of Action and Milestones (POA&M) for a period of 180 days to remediate the POA&M, see §.170.21. 4. Affirmations: Estimates consist of costs for an OSA to submit to SPRS an initial and, as applicable, any subsequent affirmations of compliance that the contractor information system is compliant with and will maintain compliance with the security requirements of the applicable CMMC Level. If POA&Ms are allowed, an affirmation must be submitted with the POA&M closeout. With the exception of Small Entities for Level 1 and Level 2, it is assumed the task requires the same labor categories and estimated hours as the final reporting phase of the assessment. The categories and rates used for estimating purposes were compiled by subject matter experts based on current data available from within the DoD contractor database for comparable labor categories. A factor estimate of 30 percent was added to the labor rate per hour to include but are not limited to company-sponsored benefits (fringe) and limited employee-related expenses such as training and certifications. This estimate is based on labor performed by indirect personnel (i.e., personnel who are part of overhead expense); therefore, the 30 percent factor represents an estimate for fringe expense and G&A expenses versus full overhead expense. The categories and rates inclusive of the labor cost plus the additional factor are defined in the table. (printed page 83181) CMMC Level 1 Self-Assessment and Affirmation Costs Other Than Small Entities Nonrecurring and recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with CMMC Level 1, since it is assumed that the contractor or subcontractor has already implemented the applicable security requirements. [46] Assessments Costs: It is estimated that the cost to support a CMMC Level 1 self-assessment and affirmation is *\$4,042 (as summarized in 4.1.2, table 9). A Level 1 self-assessment is conducted annually, and is based on the assumptions detailed: Phase 1: Planning and preparing for the self-assessment: \$1,146 A director (MGMT5) for 4 hours (\$190.52/hr × 4hrs = \$762) A manager (MGMT2) for 4 hours (\$95.96/hr × 4hrs = \$384) Phase 2: Conducting the self-assessment: \$1,728 A director (MGMT5) for 6 hours (\$190.52/hr × 6hrs = \$1,143) A staff IT specialist (IT4) for 6 hours (\$97.49/hrs × 6hrs = \$585) Phase 3: Reporting of self-assessment results into SPRS: \$584 A director (MGMT5) for 2 hours (\$190.52/hr × 2hrs = \$381) A staff IT specialist (IT4) for 2.08 hours (\$97.49/hrs × 2.08hrs = \$203) Affirmations:

The Department of the Army is proposing to amend a system of records notice in its existing inventory of records systems subject to the Privacy Act of 1974, (5 U.S.C. 552a), as amended. DATES: This proposed action will be effective without further notice on (insert date thirty days after publication in Federal Register) unless comments are received which result in a contrary determination. ADDRESSES: Department of the Army, Freedom of Information/Privacy Division, U.S. Army Records Management and Declassification Agency, ATTN: AHRC-PDD-FPZ, 7701 Telegraph Road, Casey Building, Suite 144, Alexandria, VA 22325-3905. FOR FURTHER INFORMATION CONTACT: Ms. Mary Smith at (703) 000-0000. SUPPLEMENTARY INFORMATION: The Department of the Army systems of records notices subject to the Privacy Act of 1974, (5 U.S.C. 552a), as amended, have been published in the Federal Register and are available from the address above. The specific changes to the records systems being amended are set forth below followed by the notices, as amended, published in their entirety. The proposed amendments are not within the purview of subsection (r) of the Privacy Act of 1974, (5 U.S.C. 552a), as amended, which requires the submission of a new or altered system report. Dated: February 3, 2006. John Miller, OSD Federal Register Liaison Officer, Department of Defense. A0055 USEUCOM System name: Europe Command Travel Clearance Records (August 23, 2004, 69 FR 51817). Changes: * * * * * System name: Delete system identifier and replace with:

·A0055 USEUCOM DoD·. * * * * * A0055 USEUCOM DoD System name: Europe Command Travel Clearance Records. System location: Headquarters, United States European Command, Computer Network Operations Center, Building 2324, P.O. Box 1000, APO AE 09131-1000. Categories of individuals covered by the system: Military, DoD civilians, and non-DoD personnel traveling under DoD sponsorship (e.g., contractors, foreign nationals and dependents) and includes temporary travelers within the United States European Command's (USEUCOM) area of responsibility as defined by the DoD Foreign Clearance Guide Program. Categories of records in the system: Travel requests, which contain the individual's name; rank/pay grade; Social Security Number; military branch or department; passport number; Visa Number; office address and telephone number, official and personal email address, detailed information on sites to be visited, visitation dates and purpose of visit. Authority for the maintenance of the system: 10 U.S.C. 3013 , Secretary of the Army; 10 U.S.C. 5013 , Secretary of the Navy; 10 U.S.C. 8013 , Secretary of the Air Force; DoD 4500.54-G, Department of Defense Foreign Clearance Guide; Public Law 99-399, Omnibus Diplomatic Security and Antiterrorism Act of 1986; 22 U.S.C. 4801 , 4802 , and 4805 , Foreign Relations and Intercourse; E.O. 12333 , United States Intelligence Activities; Army Regulation 55-46, Travel Overseas; and E.O. 9397 (SSN). Purpose(s):

) require the specification of a revision to a standard. Specifying a revision benefits the CMMC Ecosystem by ensuring it moves forward from one NIST standard to the next in an organized manner. The DoD cites NIST SP 800-171 R2 in this final rule for a variety of reasons, including the time needed for industry preparation to implement and time needed to prepare the CMMC Ecosystem to perform assessments against subsequent revisions. DoD is unable to incorporate suggestions that CMMC assessments be aligned to whichever NIST revision is current at the time of solicitation. Comments on the specifics on NIST SP 800-171 Revision 3 should be directed to NIST. 8. Affirmation. Commenters expressed confusion regarding the definition of the Affirming Official as well as how the affirmation process works i.e., is the affirmation for each company or the whole supply chain. One commenter also expressed confusion regarding whether an affirmation was required at each certification level annually. DoD Response. The rule was modified to include a definition for Affirming Official in § 170.4. The DoD considered the recommended text revisions and modified the text for added clarity about affirmations. DoD's use of the term OSA within the affirmations section is deliberate and conveys that each organization is responsible for affirmations pertaining to their own assessments. To help clarify the point in question, § 170.22(a)(1) addresses Affirming Official and has been revised to clarify that CMMC affirmations shall be submitted by the OSA and apply only to the information systems of that organization. The DoD deems that the requirement to annually affirm continuing compliance with the CMMC requirements at the designated CMMC Level and following the procedures in § 170.22 is not a significant additional burden. The requirement for annual affirmations takes the place of an annual recertification and ensures the Affirming Official responsible for CMMC requirements is monitoring compliance. 9. Alternatives. Several commenters provided suggestions for alternative means to implement verification of compliance with cybersecurity standards. These suggestions included the following: Provide flexibility for the CMMC AB to allow a C3PAO partial assessment of perspective Managed Service Providers. Allow small businesses to continue performing self-assessments and self-certify along with increasing the support provided to small business from DC3 to expand paying for consultants to assist with compliance as well as paying for small businesses assessments, Integrate cybersecurity and traditional counterintelligence measures, establishing a secure software development environment in a cloud that DoD hosts, as well as providing a secure environment in which small businesses could operate. Require Prime contractors to assume the cost of CMMC for their supply chain. Only assess a sampling of the Defense Industrial Base. Increase the Certification validity time period from 3 to 10 years.

The FTC urges that you immediately place an initial fraud alert on your credit file. The Fraud alert is for a period of 90 days, during which, creditors are required to contact you before a new credit card is issued or an existing card changed. The site also provides other valuable information that can be taken now or in the future if problems should develop. The DoD takes this loss very seriously and is reviewing its current policies and practices with a view of determining what must be changed to preclude a similar occurrence in the future. At a minimum, we will be providing additional training to personnel to ensure that they understand that personally identifiable information must at all times be treated in a manner that preserves and protects the confidentiality of the data. We deeply regret and apologize for any inconvenience and concern this theft may cause you. Should you have any questions, please call _____. Sincerely, Signature Block (Directorate

level or higher) Appendix C to Part 310-DoD Blanket Routine Uses (See paragraph (c) of § 310.22 of subpart E)

A. Routine Use-Law Enforcement If a system of records maintained by a DoD Component to carry out its functions indicates a violation or potential violation of law, whether civil, criminal, or regulatory in nature, and whether arising by general statute or by regulation, rule, or order issued pursuant thereto, the relevant records in the system of records may be referred, as a routine use, to the agency concerned, whether Federal, State, local, or foreign, charged with the responsibility of investigating or prosecuting such violation or charged with enforcing or implementing the statute, rule, regulation, or order issued pursuant thereto.

B. Routine Use-Disclosure When Requesting Information A record from a system of records maintained by a Component may be disclosed as a routine use to a Federal, State, or local agency maintaining civil, criminal, or other relevant enforcement information or other pertinent information, such as current licenses, if necessary to obtain information relevant to a Component decision concerning the hiring or retention of an employee, the issuance of a security clearance, the letting of a contract, or the issuance of a license, grant, or other benefit.

C. Routine Use-Disclosure Of Requested Information A record from a system of records maintained by a Component may be disclosed to a Federal agency, in response to its request, in connection with the hiring or retention of an employee, the issuance of a security clearance, the reporting of an investigation of an employee, the letting of a contract, or the issuance of a license, grant, or other benefit by the requesting agency, to the extent that the information is relevant and necessary to the requesting agency's decision on the matter.

D. Routine Use-Congressional Inquiries

Establishing uniform requirements for the Government and contractors regarding FISs will significantly assist the Government in protecting Federal information and systems from malicious cyber campaigns that threaten the public and private sectors' security and (printed page 68406) privacy. Currently, contract requirements for the cybersecurity standards of unclassified FISs are largely based on agency-specific policies and regulations, which can lead to inconsistent security requirements across contracts and unclear, inconsistent, or overly restrictive guidance to contractors. This rule will provide a more consistent and streamlined implementation of cybersecurity standards across the Federal Government.

A. Affected Entities This rule proposes two new contract clauses for use when acquiring services to develop, implement, operate, or maintain a FIS. Specifically, the contracting officer will include-

- The clause at FAR 52.239-YY, Federal Information Systems Using Non-Cloud Computing Services, in solicitations and contracts that use or may use non-cloud computing services in performance of the contract; and
- The clause at FAR 52.239-XX, Federal Information Systems Using Cloud Computing Services, in solicitations and contracts that use or may use cloud computing services in performance of the contract.

According to subject matter experts, there are approximately 140 non-cloud FISs currently being operated or maintained by contractors on behalf of the Government. For this estimate, the Government conservatively assumes that the services for each of these non-cloud FISs are awarded on individual contracts and that each contract is awarded to a unique entity. It is assumed that each of these contracts have a five-year period of performance, and that the Government evenly awards the estimated 140 contracts over a five-year period (20 percent each year). Therefore, the Government estimates it awards 28 contracts ((20 percent * 140 non-cloud FISs) * 1 contract/FIS) to 28 unique contractors (28 contracts = 28 unique entities) annually for the development, implementation, operation, or maintenance of a non-cloud FIS on behalf of the Government.

, but only to the extent that such material would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k) (5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. To protect the identity of those who give information in confidence for personnel security and related investigations. Fear of harassment could cause them to refuse to give this information in the frank and open way needed to pinpoint areas in an investigation that should be expanded to resolve charges of questionable conduct. (16) System identifier and name. F036 AF PC P, Applications for Appointment and Extended Active Duty Files. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k) (5) from the following subsection of 5 U.S.C. 552a(d) . (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. To protect the identity of confidential sources who furnish information necessary

to make determinations about the qualifications, eligibility, and suitability of health care professionals who apply for Reserve of the Air Force appointment or inter-service transfer to the Air Force. (17) System identifier and name. F036 AF DPG, Military Equal Opportunity and Treatment. (i) Exemption. Investigative material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance (printed page 14742) of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (f)(17)(i). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) from the following subsections of 5 U.S.C. 552a(d), (e)(4)(H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2). (iii) Reasons.

At that time, the Security Rule applied directly only to covered entities. As discussed above, Congress later extended the application of the Security Rule directly to business associates. Back to Citation 289. 68 FR 8334, 8343 (Feb. 20, 2003). Back to Citation 290. Id. Back to Citation 291. 78 FR 5566, 5589 (Jan. 25, 2013). Back to Citation 292. 42 U.S.C. 1320d-2(d)(1)(A)(v). Back to Citation 293. See "Why Health Care is Harder to Access in Rural America," U.S. Government Accountability Office (May 16, 2023) (When local hospitals close in rural areas, residents have to travel more than 20 miles further to receive common health care and 40 miles further to receive less common health care, such as substance use disorder treatment. Such rural areas generally have fewer health care providers overall.), <https://www.gao.gov/blog/why-health-care-harder-access-rural-america>. Back to Citation 294. See "A National Staffing Emergency in Rural Health Care," American Hospital Association (Dec. 19, 2023), <https://www.aha.org/advancing-health-podcast/2023-12-20-national-staffing-emergency-rural-health-care>. Back to Citation 295. See Debi Primeau, "How Small Organizations Handle HIPAA Compliance," Journal of the American Health Information Management Association, Volume 88, Issue 4, p. 18-21, 19 (Apr. 2017); Kat Jercich, "Rural hospitals are more vulnerable to cyberattacks-here's how they can protect themselves," Healthcare IT News (Sept. 8, 2021); see also Tami Lichtenberg, "Recovering from a Cybersecurity Attack and Protecting the Future in Small, Rural Health Organizations" (Oct. 4, 2023), <https://www.ruralhealthinfo.org/rural-monitor/cybersecurity-attacks>. Back to Citation 296. See "How Small Organizations Handle HIPAA Compliance," supra note 295, p. 19; "Rural hospitals are more vulnerable to cyberattacks-here's how they can protect themselves," supra note 295. Back to Citation 297. "Too Small to Be Attacked by Cybercriminals? Not So Fast," Same-Day Surgery, Volume 43, Issue 7 (July 2019), <https://www.reliasmedia.com/articles/144561-too-small-to-be-attacked-by-cybercriminals-not-so-fast>. Back to Citation 298. "Percent of Hospitals, By Type, that Possess Certified Health IT," Health IT Quick-Stat #52 (Sept. 2018), <https://www.healthit.gov/data/quickstats/percent-hospitals-type-possess-certified-health-it>; "Office-based Physician Electronic Health Record Adoption," Health IT Quick-Stat #50, <https://www.healthit.gov/data/quickstats/office-based-physician-electronic-health-record-adoption>. Back to Citation 299. "How Small Organizations Handle HIPAA Compliance," supra note 295, p. 19. Back to Citation 300. See id. Back to Citation 301. Id.; see also "Recovering from a Cybersecurity Attack and Protecting the Future in Small, Rural Health Organizations," supra note 295. Back to Citation 302. "Too Small to Be Attacked by Cybercriminals? Not So Fast," supra note 297. Back to Citation

Take measures to provide assurance that available inventory is in accordance with quantities listed on the inventory schedules. Quantities may be verified by actual item count, acceptance of labeled quantities in unopened/sealed packages, scale counts, or other appropriate methods. (c) Condition. Ensure that the physical condition of the property is reasonably consistent with the Federal Condition Code supplied by the contractor. 245.602-3 Screening. Property will be screened DoD-wide, including the contracting agency, requiring agency, and, as appropriate, the General Services Administration. The requiring agency shall have priority for retention of listed items. All required screening must be completed before any sale of contractor inventory, including contractor inventory in overseas locations (foreign excess personal property) can take place. Upon request of the prospective reutilization, transfer, donation, or sales customer, the plant clearance officer shall arrange for inspection of property at the contractor's plant in such a manner as to avoid interruption of the contractor's operations, and consistent with any security requirements. (

printed page 52143) 245.602-70 Plant clearance procedures. Follow the procedures at PGI 245.602-70 for establishing and processing a plant clearance case. 245.604 Disposal of surplus property. 245.604-3 Sale of surplus property. (a) Plant clearance officers shall determine a best value sales approach (formal or informal sales), to include due consideration for costs, risks, and benefits, e.g., potential sales proceeds. (b) Informal bid procedures. The plant clearance officer may direct the contractor to issue informal invitations for bid (orally, telephonically, or by other informal media), provided: (1) Maximum practical competition is obtained; (2) Sources solicited are recorded; and (3) Informal bids are confirmed in writing. (c) Sale approval and award. Plant clearance officers shall: (1) Evaluate bids to establish that the sale price is fair and reasonable, taking into consideration: (i) Knowledge or tests of the market; (ii) Current published prices for the property; (iii) The nature, condition, quantity, and location of the property; and (iv) Past sale history for like or similar items; (2) Approve award to the responsible bidder whose bid is most advantageous to the Government. The plant clearance officer shall not approve award to any bidder who is an ineligible transferee, as defined in 252.245-7004, Reporting, Reutilization, and Disposal; and (3) Notify the contractor of the bidder to whom an award will be made within five working days from receipt of bids. (d) Noncompetitive sales. (1) Noncompetitive sales include purchases or retention at less than cost by the contractor. Noncompetitive sales may be made when: (i) The plant clearance officer determines that this method is essential to expeditious plant clearance; and (ii) The Government's interests are adequately protected.

Because a notice of proposed rulemaking and an opportunity for public comment are not required to be given for this rule under 41 U.S.C. 1707(a)(1) (see section III. of this preamble), the analytical requirements of the Regulatory Flexibility Act (5 (printed page 24895) U.S.C. 601 et seq.) are not applicable. Accordingly, no regulatory flexibility analysis is required and none has been prepared. VII. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). List of Subjects in 48 CFR Parts 204 and 252 Government procurement Amy G. Williams, Deputy, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204 and 252 are amended as follows: 1. The authority citation for parts 204 and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 . PART 204-ADMINISTRATIVE MATTERS 204.1105 [Removed] 2. Remove section 204.1105. PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 252.204-7004 [Removed and Reserved] 3. Remove and reserve section 252.204-7004. [FR Doc. 2018-11347 Filed 5-29-18; 8:45 am] BILLING CODE 5001-06-P

Two comments stated that the interim final rule lacks sufficient safeguards to limit the sharing and use of personally identifiable information and content of private communications. Response: The program utilizes significant handling and sharing restrictions to ensure appropriate protections for any and all sensitive information managed by the program, including but not limited to PII. These safeguards are addressed in more detail in the PIA, which will be updated appropriately as the program evolves. No change is made to the rule. Comment: Three comments recommended that the rule should require companies to remove sensitive information (e.g., PII), and to anonymize as much information as possible (printed page 62433) without hindering cyber security efforts, and that the Government should immediately dispose of inadvertently collected PII that is not directly relevant to the cyber incident. Response: DoD agrees with the underlying premise of the comment, and the DIB CS/IA program uses procedures to minimize the collection and sharing of PII. The DIB participants remove unnecessary sensitive information (e.g., PII), and only share information if it is relevant to a cyber incident (e.g., for forensics or cyber intrusion damage assessment). All PII received by DoD is provided voluntarily by authorized DIB company representatives and is subject to mutually agreed upon restrictions for cyber security purposes. In addition, the DIB participants are required, prior to sharing any information with the Government under this program, to review and determine that their activities under the program are in compliance with all applicable laws and regulations, including restrictions on the interception, monitoring, access, use, and disclosure of electronic communications (see § 236.6(b) and (c)). Information determined to be relevant is maintained, controlled, and disposed of when no longer reasonably necessary for forensics analysis, and damage assessment activities (or other legal, audit or operational purposes). Companies are required to abide by all sharing restrictions. The PIA for the DIB CS/IA program addresses the handling safeguards in more detail. No change is made to the rule. Comment: Two comments stated that the PII the Government obtains through the DIB CS/IA program should be used only for cyber

security operations and not general law enforcement or intelligence fact gathering. The rule should also limit Government use of information shared for cyber security purposes. Response:

3 11 18 Vibrio P. 2 2 3 Chemical Ammonia 3 5 7 Methomyl 3 5 7 Sodium nitrite 3 5
7 Parasitic Cryptosporidium 17 22 60 Cyclospora 17 22 60 Toxin Ciguatera or Ciguatoxin 2
5 19 Histamine 2 5 19 Saxotoxin 2 5 19 Scromboid 2 5 19 Star Anise 2 5 19 Toxin 2
5 19 Viral Hepatitis A 22 22 28 Norovirus 2 2 6 Viral or Vitrio 2 2 6 The
distributions over mild, moderate, and severe cases for most of the illnesses were estimated from
the CDC (Ref. 3), and a CFSAN report entitled "Modeling the Effects of Food Handling Practices on
the Incidence of Foodborne Illness" (Ref. 9). The case distributions over mild, moderate, and severe
cases were estimated for chemical and marine toxin poisoning from a study by Brevard et al. (Ref.
10), and a study reported by CDC (Ref. 11). The indirect costs of an illness are the loss in
welfare measured as a loss in life quality or, in the extreme case, death from the illness. This
loss in quality of life also includes lost worker productivity while ill. Estimates of the indirect
costs will vary depending on the symptoms of the illness and their severity. We use a quality of
well-being scale for a typical gastrointestinal illness to adjust the well-being of a person with
mild, moderate, or severe symptoms (Ref. 12). The well-being scale assumes a value of 1 for a person
in good health, and is reduced according to the (printed page 71622) symptoms and impaired
mobility, reduced physical activity, and reduced social activity that result from the illness. We
compute an index of lost quality adjusted life days (QALD) by subtracting the individual's health
status when ill from one and then multiplying that fraction by the number of days the illness lasts.
The result represents the number of health days lost from an illness; we estimate the loss for
varying severities for each illness. The QALD losses for an average foodborne illness are reported
in the following table 6 of this document. Table 6. Lost QALDs Due to an Average Case of Foodborne
Illness

Severity of Illness	Symptom	Mobility	Physical	Social	Quality Adjustment	QALDs Lost
Mild	-0.29 -0.062 -0.077 -0.061	0.51	0.49	Moderate	-0.29 -0.062 -0.077 -0.061	0.51 0.49
Severe	-0.29 -0.090 -0.077 -0.061	0.48	0.52	To reflect uncertainty in the literature, FDA		

uses a range to estimate the values of the health days lost. We use a low estimate of \$100,000 for
the value of a life year. This is consistent with that proposed by Garber and Phelps, who suggest a
value of approximately twice the annual income (Ref. 13). U.S. Census data reports that the median
family income in 2001 was approximately \$51,000 (Ref. 14).

5 U.S.C. 552a(k) (5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), and (e)(1).
(ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. (A) From subsection (c)(3) and (d) when
access to accounting disclosures and access to or amendment of records would cause the identity of a
confidential sources to be revealed. Disclosure of the source's identity not only will result in the
Department breaching the promise of confidentiality made to the source but it will impair the
Department's future ability to compile investigatory material for the purpose of determining
suitability, eligibility, or qualifications for Federal civilian employment, Federal contracts, or
access to classified information. Unless sources can be assured that a promise of confidentiality
will be honored, they will be less likely to provide information considered essential to the
Department in making the required determinations. (B) From (e)(1) because in the collection of
information for investigatory purposes, it is not always possible to determine the relevance and
necessity of particular information in the early stages of the investigation. In some cases, it is
only after the information is evaluated in light of other information that its relevance and
necessity becomes clear. Such information permits more informed decision-making by the Department
when making required suitability, eligibility, and qualification determinations. (5) System
identifier and name. GNSA 05, Equal Employment Opportunity Data. (i) Exemption. (A)
Investigatory material compiled for law enforcement purposes, other than material within the scope
of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if
an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by
Federal law or for which he would otherwise be eligible, as a result of the maintenance of the
information, the individual will be provided access to the information exempt to the extent that
disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(5)(i)(A).
When claimed, this exemption allows limited protection of investigative reports maintained in a
system of records used in personnel or administrative actions. (B) Records maintained solely for
statistical research or program evaluation purposes and which are not used to make decisions on the
rights, benefits, or entitlement of an individual except for census records which may be disclosed
under 13 U.S.C. 8 , may be exempt pursuant to 5 U.S.C. 552a(k)(4) . (C) All portions of this
system of records which fall within the scope of 5 U.S.C. 552a(k)(2) and (k)(4) may be exempt

from the provisions of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f).
(ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(4) . (iii) Reasons.

From the NIST SP 800-172 Rev 3 Final Public Draft: use of removable systems in non-secure settings, and the potential targeting of 772 individuals at home. Personnel are also trained on what constitutes suspicious communications and how to respond to such communications. Training personnel on how to recognize anomalous behaviors in systems can provide organizations with early warning of the presence of malicious code. Recognizing anomalous behavior in systems can supplement the malicious code detection and protection tools and systems used by organizations. Since threats continue to change over time, threat literacy training is dynamic. Moreover, threat literacy training is not performed in isolation from the system operations that support organizational missions and business functions. This requirement enhances SP 800-171 require

Security zone-based architecture provides a standardized way of designing a scalable and consistent security architecture. It offers increased network resiliency, meaning it helps keep communications working in the face of misconfiguration and faults. Security segmentation can help mitigate the vulnerabilities listed above and should be part of a comprehensive cybersecurity plan. For example, consider the primary operational function of an asset. Some potential operational functions are real-time monitoring, controlling a machine or process, planning, scheduling of machines, business operation, administrative systems, and communication devices. Based on these criteria, assets identified in step 1 during the asset inventory can be classified into the operational function zones. An example grouping is below. This zone consists of applications and devices used for day-to-day business operation. Examples include financial applications, office applications (Word®, Excel®), manufacturing resource planning (MRP), enterprise resource planning (ERP), AutoCAD, printers, plotters, and scanners.

The following is a summary from the Regulatory Impact Analysis (RIA) of the specific compliance requirements and the estimated costs of compliance. The new FAR clause is modeled after the most recent version of the clause at DFARS 252.204-7012, which introduced many of these compliance requirements on defense contractors and subcontractors in 2015 and required compliance not later than December 31, 2017. Therefore, the estimated costs of compliance have been segregated into those that are new for Federal offerors, contractors, and subcontractors (see section IV.C.1 of this preamble) and those that are new only for non-defense contractors and subcontractors (see section IV.C.2 of this preamble). The RIA includes a detailed discussion and explanation about the assumptions and methodology used to estimate the cost of this regulatory action, including the specific impact and costs for small businesses. Public comment is requested on the RIA, which is available at <https://www.regulations.gov> (search for 'FAR Case 2017-016,' click 'Open Docket,' and view 'Supporting Documents').

1. Federal Offerors, Contractors, and Subcontractors

The following compliance requirements are considered new for Federal offerors, contractors, and subcontractors required to safeguard CUI:

a. Regulatory Familiarization

Familiarization accounts for the time to read and understand the rule. It is expected that most contractors will be required to become familiar with the various compliance requirements of the FAR, in order to be prepared to handle or receive CUI in performance of a Federal contract. According to award data in the Federal Procurement Data System (FPDS) for fiscal year (FY) 2021 through FY 2023, on average per year the Government awards contracts and orders for supplies and services to 67,547 unique contractors, all of whom are expected to become familiar with this rule. It is estimated that on average it will take two hours per contractor and subcontractor that handle CUI to review the rule. The estimated cost for regulatory familiarization in the first year of implementation is \$10,267,144 (67,547 contractors and subcontractors * 2 hours/entity * \$76/hour), of which \$6,711,104 is attributed to 44,152 small businesses.

b. Review the SF XXX

Offerors, contractors, or subcontractors will need to review the SF XXX to determine the information under the contract or subcontract that is considered CUI and how to properly safeguard the CUI. It is estimated that approximately 22,680 offerors, contractors, and subcontractors may review 2,092,918 forms for information on how to protect CUI each year. On average, it is estimated that it will take an offeror, contractor, or subcontractor two hours to review the SF XXX. The estimated annual cost to review standard forms is \$334,866,880 (2,092,918 forms * 2 hours/form * \$80), of which \$5,058,880 is attributed to 15,809 small businesses.

c. Prepare and Distribute the SF XXX

authentication; mobile devices; onscreen keyboards; password entry; password generation; password permutation; security-usability balance; text entry; usable security

Passwords are rarely lauded as

an effective authentication mechanism, yet their use is widespread. Since their inception, passwords have been a bane to the individuals using them. Users constantly forget and reset passwords. Organizations attempt to ensure that users' passwords meet minimum complexity requirements and are periodically changed as often as deemed necessary. Building upon these problems, scores of password databases have been exfiltrated from various websites since electronic commerce became commonplace. These leaked password datasets, combined with specialized hardware, provide an optimum environment to make modern password cracking software effective and efficient. We argue that only by empirically quantifying the security-usability tradeoff can we hope to measure and understand effects of changing passwords along either or both dimensions. Although alternative-and arguably better-mobile authentication mechanisms exist [2], the unfortunate reality is that passwords are too deeply ingrained in our current digital world to be fully replaced in the near term. In the longer term, research efforts such as the National Strategy for Trusted Identities in Cyberspace (NSTIC) aim to ultimately replace passwords as a primary authentication mechanism [3]. In the interim, however, our work is focused on evaluating ways to improve password usability for mobile devices without an unacceptably large sacrifice to security.

https://public3.pagefreezer.com/browse/HHS.gov/31-12-2020T08:51/https://www.hhs.gov/sites/default/files/jackson-health-system-notice-of-final-determination_508.pdf . Back to Citation 570. · See Press Release, HHS Office for Civil Rights Settles HIPAA Investigation with Arizona Hospital System Following Cybersecurity Hacking, U.S. Department of Health and Human Services (Feb. 2, 2023), <https://www.hhs.gov/about/news/2023/02/02/hhs-office-for-civil-rights-settles-hipaa-investigation-with-arizona-hospital-system.html> . Back to Citation 571. · See Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide, supra note 461. Back to Citation 572. 45 CFR 160.103 (definition of Health care clearinghouse). Back to Citation 573. 45 CFR 164.500(b) ; see also Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide, supra note 461, p. 38. Back to Citation 574. · See Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide, supra note 461, p. 38. Back to Citation 575. 45 CFR 164.308(a)(4)(ii)(C) . Back to Citation 576. 45 CFR 164.308(a)(4)(ii)(B) . Back to Citation 577. · See Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide, supra note 461. Back to Citation 578. · See 45 CFR 164.308(a)(3) ; proposed 45 CFR 164.308(a)(9)(i) . Back to Citation 579. · See proposed 45 CFR 164.312(f)(2)(ii) through (iv) . Back to Citation 580. · See Train Your Workforce, so They Don't Get Caught by a Phish!, Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (July 2017), <https://www.hhs.gov/sites/default/files/july-2017-ocr-cyber-newsletter.pdf> . Back to Citation 581. · See Training Materials, Office for Civil Rights, U.S. Department of Health and Human Services, <https://www.hhs.gov/hipaa/for-professionals/training/index.html> . Back to Citation 582. · See Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide, supra note 461. Back to Citation 583. · See Resolution Agreement, West Georgia Ambulance, Inc., Office for Civil Rights, U.S. Department of Health and Human Services (Dec. 23, 2019), <https://www.hhs.gov/sites/default/files/west-georgia-ra-cap.pdf> . Back to Citation 584. · Cybersecurity Performance Goals, supra note 18. Back to Citation 585. Id. Back to Citation 586. Proposed 45 CFR 164.308(a)(11)(ii)(A) (1). Back to Citation 587. Proposed 45 CFR 164.308(a)(11)(ii)(A) (2). Back to Citation 588. Proposed 45 CFR 164.308(a)(11)(ii)(A) (3); Letter from NCVHS Chair Jacki Monson (2023), supra note 123, Appendix p. 1; Letter from NCVHS Chair Jacki Monson (2022), supra note 123, p. 6-7. Back to Citation 589. 45 CFR 164.308(a)(5)(ii)(A) . Back to Citation 590. Proposed

. Section 164.310(c), the standard for workstation security, also is not accompanied by standalone addressable or required implementation specifications, but it does require a regulated entity to implement physical safeguards that restrict all workstations, such as a laptop or desktop computer or any other device that performs similar functions, that access ePHI to authorized users. [636] Device and media controls can help regulated entities respond to and recover from security incidents and breaches. [637] Proper understanding of and implementation of such controls may enable regulated entities to quickly determine which devices and electronic media may be implicated in an actual or suspected security incident, or breach, and respond accordingly. [638] For example, if cybercriminals gained access to an organization's network by exploiting a vulnerability

present in a particular electronic device, a robust and accurate inventory and tracking process could identify how many devices are affected and where they are located. With this information, a regulated entity should be able to make more effective use of its resources and respond more effectively to an actual or suspected security incident or breach involving such devices. Thus, it is important for regulated entities to implement the device and media controls required under 45 CFR 164.310(d). Accordingly, the standard for device and media controls at 45 CFR 164.310(d), requires a regulated entity to implement policies and procedures to govern how hardware and electronic media containing ePHI are received or removed from a facility and within a facility. Section 164.310(d)(2) includes two required and two addressable implementation specifications. Paragraphs (d)(2)(i) and (ii) on disposal and media re-use, respectively require a regulated entity to implement policies and procedures that address the final disposition of ePHI and the hardware or electronic media on which it is stored, and the removal of ePHI before the electronic media is re-used. Section 164.308(d)(2)(iii) addresses the (printed page 959) maintenance of a record of the movement of hardware and electronic media and any person responsible for such hardware or electronic media, while the provision on data backup and storage at 45 CFR 164.310(d)(2)(iv) addresses the creation of a retrievable, exact copy of ePHI before moving the equipment.

2. Issues To Address

The Department has concerns regarding the effectiveness of the language used in the physical safeguards in 45 CFR 164.310 for the same reasons discussed in the context of 45 CFR 164.306 and 164.316. For example, while 45 CFR 164.310 contemplates that a regulated entity must implement the standards and implementation specifications required under 45 CFR 164.310 in accordance with the general documentation and maintenance requirements found in 45 CFR 164.306 and 164.316

| 1 Executive Summary | 1 Executive Summary | 1 Executive Summary | 1 | |-----

-----|-----

-----|-----

-----|-----

-----|-----| | | 1 | 1.1 Purpose of the Workshop | 1.1 Purpose of the Workshop | 1.1 Purpose of the Workshop | | 1.2 Structure of the Workshop 1.3 Workshop Recommendations | 1.2 Structure of the Workshop 1.3 Workshop Recommendations | 1.2 Structure of the Workshop 1.3 Workshop Recommendations | 1 | | 2 Workshop Participants | 2 Workshop Participants | 2 Workshop Participants | 4 | | 3 Introductory Session | 3 Introductory Session | 3 Introductory Session | 5 | | 4 Session on Authentication in Distributed Networks | Session on Authentication in Distributed Networks | 7 | | | Standards and Technology | 7 | | 4.2 General Discussion on Authentication 5 Session on Access Control in Distributed Networks | 4.2 General Discussion on Authentication 5 Session on Access Control in Distributed Networks | 4.2 General Discussion on Authentication 5 Session on Access Control in Distributed Networks | | | | 16 | | 5.1 Kerberos Authentication/Access Control System - Jeff Schiller, Massachusetts | 5.1 Kerberos Authentication/Access Control System - Jeff Schiller, Massachusetts

- b. The centralized team operates as a service for the rest of the business, which includes researching and recommending specific vendors when business owners require a specific product or service. This team owns most aspects of the supplier relationship for the entire lifecycle, including developing requests for proposals, contract negotiations, and managing compliance checks.
- c. Business unit owners are responsible for selecting and requesting their own suppliers and serving as the principal manager for those relationships.

Comments also note that the proposed rule does not consider the time required to verify the completeness and accuracy of records, transmission of data to appropriate authorities and the availability of knowledgeable personnel to access specific records. They suggest that FDA should focus on the information contained in the records, rather than on the records themselves. Comments suggest FDA change the proposed language to include: As soon as possible within 24 hours from the time the request is made. Other comments state that the proposed time is not enough, particularly if the request for record is made late during the day, or on Friday, or on a day (Sunday) when the location where records are maintained is closed and insufficient staff is available to retrieve the requested records. Comments urge FDA to allow companies to provide records as quickly as is practicable, given the nature of the recordkeeper's operations. (Response) FDA agrees with these comments in part and has amended the proposed records availability requirements in this final rule. Section 1.361(a) of this final rule states: * * * Such records and other information must be made available as soon as possible, not to exceed 24 hours from the time of receipt of an official request * * *. FDA notes that, although the rule sets an outer limit of 24 hours to provide

records, it requires that records be provided as soon as possible. (Comment 143) Other comments suggest that records be available within 12 hours regardless of what time of day the FDA request is made or the next business day, in the event the next day falls on a weekend or a holiday. Some suggest a timeframe within 24 hours if the request is made during a working week and within 72 hours if a request is made during a weekend. Several comments state that the majority of businesses, especially small businesses, store records that are older than 3 weeks offsite where many storage facilities are not open on weekends and holiday. Comments also state that more than 24 hours is needed to retrieve such records and to impose criminal liability for noncompliance is unworkable and unfair. Comments urge FDA to allow companies to provide records within a reasonable period of time or that the final rule gives companies 24 hours to make records available to FDA from the time of receipt of an official request.

Control PD-12: 800-79-2. Derived PIV Credentials are optional PIV credentials introduced in FIPS 201-2 and detailed in SP 800-157 Guidelines for Derived Personal Identity Verification (PIV) Credentials [SP 800157]. The timeline for their use on mobile devices depends on Department and Agencies to achieve the ATO to issue Derived PIV Credential based on this document and on the availability of validated Derived PIV Credential tokens. No Derived PIV Credentials shall be issued unless the issuer has met the requirements of and is operating in accordance to the guidelines of SP 80079-2. 4 Re-Authorization using the revised guidelines (SP 800-79-2) is required within three (3) years of current Authorization to Operate (ATO). ## 1.4 Key Related NIST Publications The following NIST publications were utilized as the basis for the requirements listed in this document. - FIPS 201-2, Personal Identity Verification (PIV) of Federal Employees and Contractors [FIPS201-2]; - SP 800-37-1 Rev. 1, Guide for Applying the Risk Management Framework to Federal Information Systems: A Security Life Cycle Approach, or as amended [SP800-37]; - SP 800-73-4, Interfaces for Personal Identity Verification (3 Parts), or as amended [SP800-73-4] Pt. 1- End Point PIV Card Application Namespace, Data Model & Representation Pt. 2- PIV Card Application Card Command Interface Pt. 3- PIV Client Application Programming Interface ; - SP 800-76-2, Biometric Data Specification for Personal Identity Verification, or as amended [SP800-76-2]; - SP 800-78-4, Cryptographic Algorithms and Key Sizes for Personal Identification Verification (PIV), or as amended; - SP 800-85 A-4, PIV Card Application and Middleware Interface Test Guidelines (SP80073-4 Compliance), or as amended; - SP 800-85 B-4, PIV Data Model Conformance Test Guidelines, or as amended; and - SP 800-157 Guidelines for Derived Personal Identity Verification (PIV) Credentials, or as amended [SP800-157].

(B) Contractors will promptly report to the CSA any emergency situation that renders them incapable of safeguarding classified material. (b) Standards for Security Equipment. Contractors will follow guidelines established in 32 CFR part 2001, when procuring storage and destruction equipment. Authorized repairs for GSA-approved security containers and vaults must be in accordance with Federal Standard 809. (c) Storage. Contractors will store classified information and material in General Services Administration (GSA)-approved security containers, vaults built to Federal Standard 832, or an open storage area constructed in accordance with 32 CFR 2001.53. In the instance that an open storage area has a false ceiling or raised floor, contractors shall develop and implement procedures to ensure their structural integrity. Nothing in 32 CFR part 2001, should be construed to contradict or inhibit compliance with local laws or building codes, but the contractor will notify the applicable CSA if there are any conflicting issues that would inhibit compliance. Contractors will store classified material in accordance with the specific sections of 32 CFR 2001.43 : (1) CONFIDENTIAL. See 32 CFR 2001.43(b)(3). (2) SECRET. See 32 CFR 2001.43(b)(2). (3) TOP SECRET Documents. See 32 CFR 2001.43(b)(1). (d) Intrusion Detection Systems (IDS). This paragraph specifies the minimum standards for an approved IDS when used for supplemental protection of TOP SECRET and SECRET material. The CSA will provide additional guidance for contingency protection procedures in the event of IDS malfunction, including contractors located in USG owned contractor operated facilities. (1) CSA approval. (i) CSA approval is required before installing an IDS. The CSA will base approval of a new IDS on the criteria of Intelligence Community Directive 705 (available at: https://www.dni.gov/files/documents/ICD/ICD_705_SCIFs.pdf) and any applicable intelligence community standard, Underwriters Laboratories (UL) Standard 2050 (Government agencies with a role as a CSA or CSO may obtain this reference without charge; available at: www.ul.com/contact), or the CSA may base approval on written CSA-specific standards for the information to be protected. (ii) Installation will be performed by an alarm services company certified by a NRTL that meets the requirements in 29 CFR 1910.7 to perform testing and certification. The NRTL-approved alarm

service company is responsible for completing the appropriate alarm system description form approved by the NRTL. (iii) All the intrusion detection equipment (IDE) used in the IDS installation will be tested and approved (or listed) by a NRTL, ensuring its proper operation and resistance from tampering. Any IDE that has not been tested and approved by a NRTL will require CSA approval. (2) Central monitoring station.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [Docket Number DARS-2025-0006; OMB Control Number 0704-0478] AGENCY: Defense Acquisition Regulations System; Department of Defense (DoD). ACTION: Notice. SUMMARY: The Defense Acquisition Regulations System has submitted to OMB for clearance the following proposal for collection of information under the provisions of the Paperwork Reduction Act. DATES: DoD will consider all comments received by February 4, 2026. SUPPLEMENTARY INFORMATION: Title and OMB Number: Safeguarding Covered Defense Information, Cyber Incident Reporting, and Cloud Computing; OMB Control Number 0704-0478. Affected Public: Businesses or other for-profit and not-for-profit institutions. Respondent's Obligation: Required to obtain or retain benefits. Reporting Frequency: On occasion. Number of Respondents: 1,971. Responses per Respondent: 8.2, approximately. Annual Responses: 16,223. Average Burden per Response: 0.42 hours. Annual Burden Hours: 6,770. Needs and Uses: Offerors and contractors must report cyber incidents on unclassified networks or information systems, within cloud computing services, and when they affect contractors designated as providing operationally critical support, as required by statute. a. The clause at DFARS 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, covers cyber incident reporting requirements for incidents that affect a covered contractor information system or the covered defense information residing therein, or that affects the contractor's ability to perform the requirements of the contract that are designated as operationally critical support and identified in the contract. b. The provision at DFARS 252.204-7008, Compliance with Safeguarding Covered Defense Information Controls, requires an offeror that proposes to vary from any of the security controls of National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 in effect at the time the solicitation is issued to submit to the contracting officer a written explanation of how the specified security control is not applicable or an alternative control or protective measure is used to achieve equivalent protection.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA, CRS ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Limit (Reduce) NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 REFERENCES 1907

CeFi stablecoins have corresponding off-blockchain businesses that are usually accessible (e.g., to regulator and auditors) like any other business. DeFi stablecoins may or may not have an associated off-blockchain business or owner. The rest of this section explores each type in greater detail. The prose descriptions of fiat currency, cryptocurrency, and algorithmic-backed stablecoins follow the ordering of the characteristics list from Section 3.3. The description of the non-currency asset-backed stablecoins does not since its characteristics are almost identical to the fiat currency-backed. Private institutional stablecoins are issued for the execution of 'internal account transactions, liquidity management, and transactions between user accounts' between the financial customers of the issuer [1]. Such a stablecoin is implemented on a private blockchain (i.e., the public does not have access). The issuer thus knows all network participants and acts as the custodian of the participants' financial accounts. Stability is achieved by the issuer guaranteeing a specific redemption price for the coins backed by the deposits of the customers and issuer. Only the issuer has visibility into the customer accounts that act together as a reserve for the coin (although periodic attestations or audits could confirm this).

(l) 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information (DATE). 43. Amend section 52.213-4 by: a. Revising the date of the clause; b. Removing from paragraph (a)(2)(vii) ·NOV 2024· and adding ·(DATE)· in its place; and c. Revising paragraph (b)(2)(i); d. Redesignating paragraphs (b)(2)(ii) through (v) as paragraphs (b)(2)(iv) through (vii); and e. Adding new paragraphs (b)(2)(ii) and (b)(2)(iii). The revisions and addition

read as follows: 52.213-4 Terms and Conditions-Simplified Acquisitions (Other Than Commercial Products and Commercial Services). * * * * * Terms and Conditions-Simplified Acquisitions (Other Than Commercial Products and Commercial Services) (DATE) (b) * * * (2) * * * (i) 52.204-21, Basic Safeguarding of Covered Contractor Information Systems (DATE) (Applies to solicitations and contracts, except acquisitions solely for commercially available off-the-shelf items or Federally-funded basic and applied research in science, technology, and engineering at colleges, universities, and laboratories in accordance with National Security Decision Directive 189 when the agency does not provide any covered Federal information to the Contractor.) (ii) 52.204-XX, Controlled Unclassified Information (DATE) (Applies to solicitations and contracts, except acquisitions solely for commercially available off-the-shelf items). (iii) 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information (DATE). * * * * * 52.227-10 [Amended] 44. Amend section 52.227-10 by removing from the introductory text the phrase ·27.203-2· and adding ·27.203-3· in its place. 45. Amend section 52.244-6 by· a. Revising the date of the clause; b. Removing from paragraph (c)(1)(v) ·NOV 2021· and ·FAR clause 52.204-21· and adding ·DATE· and ·clause 52.204-21· in their places, respectively; and c. Redesignating paragraphs (c)(1)(x) through (xxiv) as paragraphs (c)(1)(xii) through (xxvi) and adding new paragraphs (c)(1)(x) through (xi). The revision and additions reads as follows: 52.244-6 Subcontracts for Commercial Products and Commercial Services. * * * * * Subcontracts for Commercial Products and Commercial Services (DATE) * * * * * (c)(1) * * * (x) 52.204-XX, Controlled Unclassified Information (DATE), if flow down is required in accordance with paragraph (e) of clause 52.204-XX. (xi) 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information (DATE), if flow down is required in accordance with paragraph (e) of clause 52.204-YY. * * * * * PART 53-FORMS 46. Revise the heading of section 53.204 to read as follows: 53.204 Administrative and information matters. * * * * * 47. Amend section 53.204-1 by· a. Revising the section heading; b. Removing from the introductory text the phrase ·subpart 4.4· and adding ·4.402· in its place; c. Removing from paragraph (a) the phrase ·See 4.403 (c)(1).· and adding ·See 4.402-2 (c)(1).· in its place. The revision reads as follows: 53.204-1

(iii) All changes under this criterion require a change to the ·Categories of Records in the System· caption of the notice. (see § 310.32(f)). (3) An alteration of how the records are organized or the manner in which the records are indexed and retrieved. (i) The change must alter the nature of use or scope of the records involved (for example, combining records systems in a reorganization). (ii) Any change under this criteria requires a change in the ·Retrievability· caption of the system notice. (see § 310.32(j)(2)). (iii) If the records are no longer retrieved by name or personal identifier cancel the system notice. (see § 310.10(b)). (4) A change in the purpose for which the information in the system is used. (i) The new purpose must not be compatible with the existing purposes for which the system is maintained. (ii) If the use is compatible and reasonably expected, there is no change in purpose and no alteration occurs. (iii) Any change under this criterion requires a change in the ·Purpose(s)· caption (see § 310.32(h)) and may require a change in the ·Authority for maintenance of the system· caption (see § 310.32). (5) Changes that alter the computer environment (such as changes to equipment configuration, software, or procedures) so as to create the potential for greater or easier access. (i) Increasing the number of offices with direct access is an alteration. (ii) Software applications, such as operating systems and system utilities, that provide for easier access are considered alterations. (iii) The addition of an on-line capability to a previously batch-oriented system is an alteration. (iv) The addition of peripheral devices such as tape devices, disk devices, card readers, printers, and similar devices to an existing IT system constitute an amendment if system security is preserved. (see § 310.34). (v) Changes to existing equipment configuration with on-line capability need not be considered alterations to the system if: (A) The change does not alter the present security posture; or (B) The addition of terminals does not extend the capacity of the current operating system and existing security is preserved. (vi) The connecting of two or more formerly independent automated systems or networks together creating a potential for greater access is an alteration. (vii) Any change under this caption requires a change to the ·Storage· caption element of the systems notice. (see § 310.32(j)(i)). (c) Reports of new and altered systems. (1) Components shall submit a report for all new or altered systems to the DPO consistent with the requirements of this subpart and in the format prescribed at Appendix F of this part. (i) Components shall include the following when submitting an alteration for a system notice for publication in the Federal Register : (A) The system identifier and name. (see § 310.32(b) and (c)). (B) A description of the nature and specific changes proposed.

3.4.2 Tracing Sub-Capabilities to Attack Steps ... 3.4.2 Tracing Sub-Capabilities to Attack Steps

By tracing the sub-capabilities of a security capability to attack steps, it is clearer how the security capability addresses the attack step.

Persons who manufacture, process, pack, distribute, receive, hold, or import food in the United States must establish and maintain the following records to identify the immediate previous sources and immediate subsequent recipients for all food they receive and release, unless otherwise excluded from the requirements of subpart J of this final rule: Name, address, telephone number and, if available, fax number, and e-mail address of the immediate previous source and subsequent recipient; Adequate description; Date received or released; For persons who manufacturer, process, or pack food, the lot or code number or other identifier; Quantity and how the food is packaged; and Name, address, telephone number and, if available, fax number, and e-mail (printed page 71564) address of the transporter who transported the food to and from you. Persons who have possession, custody, or control of food in the United States for the sole purpose of transporting the food, or foreign persons who transport food in the United States, regardless of whether they have possession, custody, or control of the food for the sole purpose of transporting that food (transporters), can meet the requirements of subpart J of this final rule by: (1) Establishing and maintaining the records listed in § 1.352(a); or (2) Establishing and maintaining specified information that is in the records required of roadway interstate transporters by the Department of Transportation's (DOT's) Federal Motor Carrier Safety Administration (FMCSA) contained in 49 CFR 373.101 and 373.103 as of the date of publication of this final rule; or (3) Establishing and maintaining specified information that is in the records required of rail and water interstate transporters by the DOT's Surface Transportation Board (STB) contained in 49 CFR 1035.1 and 1035.2 as of the date of publication of this rule; or (4) Establishing and maintaining specified information that is in the records required of international air transporters on air waybills by the Warsaw Convention as Amended at the Hague, 1995 and by Protocol No. 4 of Montreal, 1975 (Warsaw Convention); or (5) Entering into an agreement with a nontransporter immediate previous source (if located in the United States) or immediate subsequent recipient (if located in the United States) to establish, maintain, or establish and maintain, the required records in options 1 or 2 of the previous paragraphs. The agreement must contain certain elements specified in § 1.352(e). If you are a nontransporter, you must retain for 6 months after the dates you receive and release the food all required records for any food for which a significant risk of spoilage, loss of value, or loss of palatability occurs within 60 days after the date you receive or release the food.

At the completion of a Level 3 certification assessment and annually following a Final CMMC Status Date, the Affirming Official shall submit a CMMC affirmation attesting to continuing compliance with all requirements of the CMMC Status Level 3 (DIBCAC). Because C3PAOs and DCMA DIBCAC check for compliance with different requirements in their respective assessments, OSCs must annually affirm their CMMC Status of Level 2 (C3PAO) in addition to their CMMC Status of Level 3 (DIBCAC) to maintain eligibility for contracts requiring compliance with Level 3. An affirmation shall also be submitted at the completion of a POA&M closeout certification assessment. § 170.23 Application to subcontractors. (a) CMMC requirements apply to prime contractors and subcontractors throughout the supply chain at all tiers that will process, store, or transmit any FCI or CUI on contractor information systems in the performance of the DoD contract or subcontract. Prime contractors shall comply and shall require subcontractors to comply with and to flow down CMMC requirements, such that compliance will be required throughout the supply chain at all tiers with the applicable CMMC level and assessment type for each subcontract as follows: (1) If a subcontractor will only process, store, or transmit FCI (and not CUI) in performance of the subcontract, (printed page 83236) then a CMMC Status of Level 1 (Self) is required for the subcontractor. (2) If a subcontractor will process, store, or transmit CUI in performance of the subcontract, then a CMMC Status of Level 2 (Self) is the minimum requirement for the subcontractor. (3) If a subcontractor will process, store, or transmit CUI in performance of the subcontract and the associated prime contract has a requirement for a CMMC Status of Level 2 (C3PAO), then the CMMC Status of Level 2 (C3PAO) is the minimum requirement for the subcontractor. (4) If a subcontractor will process, store, or transmit CUI in performance of the subcontract and the associated prime contract has a requirement for the CMMC Status of Level 3 (DIBCAC), then the CMMC Status of Level 2 (C3PAO) is the minimum requirement for the subcontractor. (b) As with any solicitation or contract, the DoD may provide specific guidance pertaining to flow-down. § 170.24 CMMC Scoring Methodology. (a) General. This scoring methodology is designed to provide a measurement of an OSA's implementation status of the NIST SP

800-171 R2 security requirements (incorporated by reference elsewhere in this part, see § 170.2) and the selected NIST SP 800-172 Feb2021 security requirements (incorporated by reference elsewhere in this part, see § 170.2). The CMMC Scoring Methodology is designed to credit partial implementation only in limited cases (e.g., multi-factor authentication IA.L2-3.5.3). (b) Assessment findings. Each security requirement assessed under the CMMC Scoring Methodology must result in one of three possible assessment findings, as follows: (1) Met.

(ii) The full text of the system notice need not be submitted if the master registry contains a current system notice for the system. (see § 310.32(q)). (2) The DPO coordinates all reports of new and altered systems with the Office of the Assistant Secretary of Defense (Legislative Affairs), Department of Defense. (3) The DPO prepares and sends a transmittal letter that forwards the report, as well as the new or altered system notice, to OMB and Congress. (4) The DPO shall publish in the Federal Register a system notice for new or altered systems. (d) Time restrictions on the operation of a new or altered system. (1) The reports, and the new or altered system notice, must be provided OMB and Congress at least 40 days prior to the operation of the new or altered system. The 40 day review period begins on the date the transmittal letters are signed and dated. (2) The system notice must be published in the Federal Register before a Component begins to operate the system (i.e., collect and use the information). If the new system has routine uses or the altered system adds a new routine use, no records may be disclosed pursuant to the routine use until the public has had 30 days to comment on the proposed use. (3) The time periods run concurrently. (e) Exemptions for new systems. See § 310.30(e) for the procedures to follow in submitting exemption rules for a new system of records or for submitting an exemption rule for an existing system of records. § 310.34 Amendment and deletion of system notices. (a) Criteria for an amended system notice. (1) Certain minor changes to published systems notices are considered amendments and not alterations. (see § 310.33(b)). (2) Amendments do not require a report of an altered system (see § 310.33(c)), but must be published in the Federal Register . (b) System notices for amended systems. Components shall include the following when submitting an amendment for a system notice for publication in the Federal Register : (1) The system identifier and name. (see § 310.32 (b) and (c)). (2) A description of the nature and specific changes proposed. (3) The full text of the system notice need not be submitted if the master registry contains a current system notice for the system. (see § 310.32(q)). (c) Deletion of system notices. (1) Whenever a system is discontinued, combined into another system, or determined no longer to be subject to this part, a deletion notice is required. (2) The notice of deletion shall include: (i) The system identification and name. (ii) The reason for the deletion. (3) When the system is eliminated through combination or merger, identify the successor system or systems in the deletion notice. (d) Submission of amendments and deletions for publication. (1) Submit amendments and deletions to the DPO for transmittal to the Federal Register for publication. (2) Multiple deletions and amendments may be combined into a single submission. Subpart H Training Requirements § 310.35 Statutory training requirements. The Privacy Act (5 U.S.C. 552a

From the NIST SP 800-172 Rev 3 Final Public Draft: Department of Commerce Howard Lutnick, Secretary National Institute of Standards and Technology Craig Burkhardt, Acting Under Secretary of Commerce for Standards and Technology and Acting NIST Director NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 Certain equipment, instruments, software, or materials, commercial or non-commercial, are identified in this paper in order to specify the experimental procedure adequately. Such identification does not imply recommendation or endorsement of any product or service by NIST, nor does it imply that the materials or equipment identified are necessarily the best available for the purpose. There may be references in this publication to other publications currently under development

Increased total time for the contractor to prepare for the assessment, including limited time for learning the reporting and affirmation processes Allowance for use of consulting firms to assist with the assessment process Time for a senior level manager to review the assessment and affirmation before submitting the results in SPRS Updated government and contractor labor rates that include applicable burden costs As a result, some costs of the revised CMMC Program may be higher than those included in the initial CMMC Program. The revised CMMC Program impact analysis includes estimated costs for implementation of the revised CMMC Program requirements across Level 1, Level 2, and Level 3 for the Public (small and other than small entities, including the CMMC Ecosystem as set forth in 32 CFR subpart C) and the Government. In summary, the total estimated Public and Government costs associated with this rule, calculated for a 20-year horizon in 2023

dollars at a 7 percent discount rate and a 3 percent discount rate are provided as follows:

Estimating the number of CMMC assessments for unique entities per level per year is complicated by the fact that companies may serve as a prime contractor on one effort but a subcontractor on others, and may also enter into subcontract agreements with more than one prime contractor for various opportunities. In addition, the CMMC Program relies upon free market influences of supply and demand to propel implementation. Specifically, the Department does not control which defense contractors aspire to compete for which business opportunities, nor does it control access to the assessment services offered by C3PAOs. OSAs may elect to complete a self-assessment or pursue a certification assessment at any time after issuance of the rule, in an effort to distinguish themselves as competitive for efforts that require an ability to adequately protect CUI. For that reason, the number of CMMC assessments for unique entities per level per year may vary significantly from the assumptions used in generating the cost estimate. The estimates represent the best estimates at this time based on internal expertise and public feedback. DoD utilized historical metrics gathered for the initial CMMC Program and subject matter expertise from Defense Pricing and Contracting (DPC) and DCMA DIBCAC to estimate the number of entities by type and by assessment level for this analysis. The following table summarizes the estimated profile used in this analysis. (printed page 83177)

Section 170.5 addresses that the CMMC Program does not alter the requirements imposed on contractors and subcontractors in FAR 52.204-21, DFARS subpart 204.73, or any other applicable safeguarding of information requirement. The CMMC Program verifies implementation of security requirements in FAR 52.204-21, NIST SP 800-171 Rev 2, and NIST SP 800-172, as applicable. Section 170.6-CMMC PMO Section 170.6 addresses the CMMC Program Management Office (PMO) functions that are performed within the (printed page 89064) Department of Defense Chief Information Officer (DoD CIO). Section 170.7-DCMA DIBCAC Section 170.7 addresses how DCMA DIBCAC will support the CMMC Program by conducting CMMC Level 2 assessments of the Accreditation Body and C3PAOs; conducting CMMC Level 3 assessments for OSCs; and recording results, issuing certificates, tracking appeals, and retaining records as required. Section 170.8-Accreditation Body Section 170.8 addresses the roles and responsibilities of the Accreditation Body, as well as requirements that the Accreditation Body must meet. The Accreditation Body must be a member in good standing with the Inter-American Accreditation Cooperation (IAAC) and become an International Laboratory Accreditation Cooperation (ILAC) Mutual Recognition Arrangement (MRA) signatory, with a signatory status scope of ISO/IEC 17020:2012 and be compliant with ISO/IEC 17011:2017. [13] There is only one Accreditation Body for the DoD CMMC Program at any given time, and its primary mission is to authorize and accredit the C3PAOs. Prior to the Accreditation Body being compliant with ISO/IEC 17011:2017 and completing a peer assessment of conformity with the IAAC in accordance with the ISO Committee on Conformity Assessment, [14] the Accreditation Body may authorize but not accredit C3PAOs. After the Accreditation Body has achieved compliance with ISO/IEC 17011:2017 and completed a peer assessment of conformity with the IAAC in accordance with the ISO Committee on Conformity Assessment, the Accreditation Body may accredit C3PAOs. The Accreditation Body also oversees the CAICO to ensure compliance with ISO/IEC 17024:2012 [15] and to ensure all training products, instruction, and testing materials are of high quality. Section 170.8 addresses specific requirements for the Accreditation Body with regards to national security background checks, foreign ownership, reporting, information protection, and appeals. The Accreditation Body will also develop policies for Conflict of Interest (Col), Code of Professional Conduct (CoPC), and Ethics that comply with all ISO/IEC 17011:2017 and DoD requirements. These policies will apply to the Accreditation Body as well as to all other individuals, entities, and groups within the CMMC Ecosystem. The information systems used by the Accreditation Body to process CMMC information have to meet all of the security requirements for CMMC Level 2 and will be assessed by DCMA's Defense Industrial Base Cybersecurity Assessment Center (DIBCAC).

(iv) In the case where a contractor is cleared to the SECRET level under an SSA, and also has a subsidiary with a TS FCL based on an approved NID, some or all of the outside directors of the cleared parent contractor may be sponsored for eligibility for access to TS information with their TS PCLs held by the subsidiary. Access will be at the level necessary for the outside directors to carry out their security or business responsibilities for oversight of the subsidiary company in accordance with DoD 5220.22-M. If the subsidiary has an approved NID for access to SAP or SCI, the applicable GCA may determine that an outside director at the parent contractor requires approved access at the subsidiary. (7) Technology Control Plans (TCPs). Under a VTA, PA, SSA, SCA, or Limited FCL, DSS will require the contractor to develop and implement a TCP as required in DoD

5220.22-M. DSS will evaluate and, if the plan is adequate, approve the TCP. The TCP must include a description of all security measures required to prevent the unauthorized disclosure of classified or export-controlled information. Although TCPs must be tailored to the specific circumstances of the contractor or corporate family to be effective, DSS may provide examples of TCPs to the contractor to assist plan creation. (8) Electronic Communication Plan (ECP). Under a VTA, PA, or SSA, DSS will require the contractor to develop and implement an ECP tailored to the contractor's operations. DSS will determine the extent of the ECP and review the plan for adequacy. The ECP must include a detailed network description and configuration diagram that clearly delineates which networks will be shared and which will be protected from access by the foreign parent or its affiliates. The network description will address firewalls, remote administration, monitoring, maintenance, and separate email servers, as appropriate. (9) Administrative Support Agreement (ASA). There may be circumstances when the parties to a transaction propose in the FOCI action plan that the U.S. contractor provides certain services to the foreign interest, or the foreign interest provides services to the U.S. contractor. The services to be provided must be such that there is no violation of the applicable FOCI mitigation or negation agreement. If approved, the extent of such support and limitations on the support will be fully documented in an ASA. (10) Annual Review and Certification (i) Annual Meeting. DSS will meet at least annually with the GSCs of contractor's operating under a VTA, PA, SSA, or SCA to review and discuss the purpose and effectiveness of the FOCI mitigation or negation agreement; establish a common understanding of the operating requirements and their implementation; answer questions from the GSC members; and provide guidance on matters related to FOCI mitigation and industrial security. These meetings will also include an examination by DSS, with the participation of the (FSO) and the GSC members, of:

Company has the "Touche Ross Audit Process." Generally, these are available from the CPA firms. Auditors should inquire of the firms auditing governmental agencies as to what audit guides they have available, and request them if the firms make them available to their clients or other interested parties. 12. STANDARDS FOR AUDIT OF GOVERNMENT ORGANIZATIONS, PROGRAMS, ACTIVITIES, AND FUNCTIONS.

This year also brought additional security challenges along with the everadvancing improvements in technology, improvements in citizens' access to government systems and information, faster communications, reduced paperwork, and streamlined processes. Our work this year met those security challenges with a breadth and depth of security areas intended to allow our customers to accomplish their missions while providing for confidentiality of their information, maintaining the availability of their resources and ensuring the integrity of their data. High priority was given to initiating a competitive program for replacement of current secure hashing algorithms employed in data source and content integrity protection mechanisms. Develop and improve mechanisms to protect the integrity, confidentiality, and authenticity of Federal agency information by developing security mechanisms, standards, testing methods, and supporting infrastructure requirements and methods. An important step that Federal organizations should take to securely manage their information and media is to categorize their information in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems. FIPS 199 requires Federal agencies to categorize their information systems as low-impact, moderate impact, or high-impact for the security objectives of confidentiality, integrity, and availability. Based on the results of categorization for confidentiality, organizations should then select appropriate sanitization methods to protect their information.

All assets within an OSA defined CMMC Level 2 or 3 assessment boundary have access to CUI and can process, store, or transmit CUI. They are therefore subject to DFARS clause 252.204-7012 and required to meet NIST SP 800-171 requirements. This is the authority for including Contractor Risk Managed Assets (CRMAs) within CMMC assessments. For Level 2, DoD has decided to assume some risk and lessen the assurance burden for a class of these assets called Contractor Risk Managed Assets, as specified in table 3 to § 170.19(c)(1). DoD does not assume this risk at Level 3. CRMAs are subject to assessment against all CMMC requirements as specified in table 5 to § 170.19(d)(1). 19. CMMC Assessment Scope and FedRAMP Moderate Equivalency Requirements Comment: Several commenters identified inconsistencies between rule content and a separate DoD policy memo that defines requirements Cloud Service Providers (CSPs) must meet to be considered FedRAMP moderate equivalent in the context of DFARS clause 252.204-7012. One commenter requested administrative changes to the rule for consistency, while others requested more substantive changes to deconflict the rule with DoD's policies. Differences between the two documents left some commenters unclear about when a CSP

would be considered within a CMMC assessment scope or required to meet CMMC requirements. They also noted that some CSPs refuse to provide clients with Customer Responsibility Matrices (CRMs), which could impede an OSAs ability to meet CMMC requirements. One commenter asked for specific instances when a FedRAMP-moderate-authorized CSP would not be accepted as meeting CMMC requirements or which requirements such a CSP could not meet. Another commenter stated the FedRAMP moderate equivalency requirements for CSPs in this rule will create confusion because they address only the NIST SP 800-171 requirements and do not include the additional cyber incident reporting requirements (printed page 83139) identified in DFARS clause 252.204-7012. One comment suggested that any expectation for CSPs to meet the DFARS clause 252.204-7012 requirements for cyber incident reporting or completion of a System Security Plan should be referenced in this CMMC rule. Another commenter suggested that all DoD contracts with CUI should include clauses and provisions for CSPs to meet Federal requirements, including a self-assessment and certification of their systems. One commenter asked whether it is sufficient for MSP/MSSPs to have FedRAMP certification instead of CMMC certification. Another interpreted the rule's wording related to security protection assets and data as expanding requirements levied on CSPs.

Organization-Defined Parameters 3161 T his appendix lists the ODPs that are included in the enhanced security requirements in Sec. 3. The ODPs are listed sequentially by requirement family, beginning with the first requirement containing an ODP in the Access Control family and ending with the last requirement containing an ODP in the Supply Chain Risk Management family. Embedded ODPs are listed as a single entry in the table. Table 4. Organization-defined parameters

ENHANCED SECURITY REQUIREMENT	ORGANIZATION-DEFINED PARAMETER
03.01.01E	[Assignment: organization-defined privileged commands and/or other organization-defined actions]
03.01.02E	[Assignment: organization-defined restrictions]
03.01.04E	[Assignment: organization-defined account and/or account type]
03.01.04E	[Assignment: organization-defined number]
03.01.08E	[Assignment: organization-defined atypical usage]
03.01.08E	[Assignment: organization-defined personnel or roles]
03.01.09E	[Assignment: organization-defined attributes to assume access permissions]
03.01.10E	[Assignment: organization-defined security attributes]
03.01.10E	[Assignment: organization-defined information, source, and destination objects]
03.01.10E	[Assignment: organization-defined information flow control policies]
03.01.11E	[Assignment: organization-defined roles and users authorized to assume such roles]
03.01.12E	[Assignment: organization-defined mechanisms and/or techniques]
03.01.13E	[Assignment: organization-defined metadata]
03.01.14E	[Assignment: organization-defined security policy filters]
03.01.14E	[Assignment: organization-defined information flows]
03.01.14E	[Selection (one or more): Block; Strip; Modify; Quarantine]
03.01.14E	[Assignment: organization-defined security policy]
03.01.15E	[Assignment: organization-defined data type identifiers]
03.01.16E	[Assignment: organization-defined policy-relevant subcomponents]
03.01.17E	[Assignment: organization-defined unsanctioned information]
03.01.17E	[Assignment: organization-defined security policy]
03.02.01E	[Assignment: organization-defined indicators of malicious code]
03.02.01E	[Assignment: organization-defined frequency]
03.02.01E	[Assignment: organization-defined events]
03.02.03E	[Assignment: organization-defined personnel]
03.02.04E	[Assignment: organization-defined personnel or roles]
03.03.02E	[Assignment: organization-defined real-time period]
03.03.02E	[Assignment: organization-defined personnel, roles, and/or locations]
03.03.02E	[Assignment: organization-defined audit logging failure events requiring real-time alerts]
03.03.03E	[Selection (one or more): movement; deletion]

Medical identity fraud also enables thieves to obtain medical treatment using the victim's stolen ePHI. This can lead to the thief's medical conditions being incorporated into the victim's medical records and impacting the victim's ability to receive appropriate medical treatment based on accurate records in the future, or any care at all depending on whether the thief has exhausted the victim's insurance benefits. [973] Overall, recovering compromised ePHI and addressing the consequences of breached information can be a long and arduous process that can cost victims large amounts of time, energy, and money. [974] Breaches of ePHI maintained by health care systems can also pose a threat to the medical well-being of affected individuals. Cyberattacks on health care organizations can include the deployment of malware that compromises the function of both internal and external medical devices. Such software can alter the dosages of sensitive medicines or shut down devices while they are in use, thus affecting patient care. [975] Some of the medical devices that are vulnerable to malicious software attacks include insulin pumps and cardiac implant devices. [976] The consequences of a cyberattack on such a medical device can be fatal. Cyberattacks on relevant electronic information systems also hinder the efficiency of hospitals and limit the quality of care provided to patients. Breaches of relevant electronic

information systems negatively affect the routine functions of health care organizations. They can affect the availability of ePHI and relevant electronic information systems and redirect critical resources from patient care to addressing the cybersecurity attack. A 2020 cyberattack on a large covered entity disrupted communication and clinician access to medical records, including to individualized chemotherapy plan templates and tools for communicating during treatment preparation and delivery. [977] In the first week following the attack, the hospital's ability to provide critical outpatient care was reduced by 40 percent and infusion visit volume decreased by 52 percent. Many patients had to be transferred to other sites to minimize delays in receiving critical medications. The effects of this data breach are not unique to this provider. There is evidence that cyberattacks on health care organizations decrease the number of patients they are able to treat in a given day and staff utilization. [978] Decreases in efficiency and number of treated patients also cause health care facilities to lose revenue because of their inability to provide care during a cybersecurity event. Similar to the effects of breaches of ePHI on individuals, health care organizations and facilities also experience reputational and financial impacts because of cybersecurity attacks. Hospitals can lose the community's trust and be subject to lawsuits from individuals whose data was compromised. [979]

On November 5, 2010, FISSEA hosted a workshop, Connecting the DOTS - Harmonizing Current Cybersecurity Competency Efforts, at NIH. Chris Kelsall, Director of the Cyber/IT Workforce, Department of the Navy, moderated a panel including Ernest McDuffie, lead for the National Initiative for Cybersecurity Education; Jacque Caldwell, lead Cybersecurity Competencies Efforts, U.S. Office of Personnel Management (OPM); Alan Carswell, Chair of the University of Maryland University College (UMUC) Cybersecurity Master's Program; and Dagne Fulcher, InfoSec Workforce Development Matrix Project. Attendees were able to obtain an overview of several cybersecurity workforce development efforts in order to enhance integration among past, current, and future endeavors. The workshop provided an open forum for discussion about how the efforts support, conflict, and/or overlap; attendees also shared viewpoints on concrete actions to support appropriate standardizing bodies. The 2011 FISSEA conference returned to NIST on March 15-17, 2011, and the theme was 'Bridging to the Future Emerging Trends in Cybersecurity.' The theme was chosen to reflect current projects, trends, and initiatives that will provide pathways to future solutions. Approximately 165 information systems security professionals and trainers attended, primarily from federal agencies, but also from academia and industry. Attendees received an update on the NICE activities, gained new techniques for developing and conducting training, as well as awareness and training ideas, resources, and contacts. Presenters represented NIST, the Department of Homeland Security (DHS), the Defense Intelligence Agency (DIA), the U.S.

Of course, when the integrator has any records or other information available to FDA under sections 414 and 704(a) of the FD&C Act, then FDA would have access to those records if FDA has a reasonable belief that the food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals. B. Foreign Trade Issues (Comment 14) Several comments representing foreign governments and international associations agree in principle to the recordkeeping requirements provided the requirements are based on a sound risk assessment and do not restrict trade more than necessary to effectively address potential risks. Some comments note that there is no risk assessment provided to justify the proposed measures required by the World Trade Organization Agreement on the Application of Sanitary and Phytosanitary Measures (SPS agreement). Several comments representing foreign governments and businesses request that FDA work with foreign governments to develop common standards and requirements and to facilitate trade flow. Some foreign comments argue that the result of the onerous recordkeeping burden in the regulations will be the elimination of many legitimate and safe food distribution businesses and a serious reduction in global food trade. One comment suggests that the regulations will adversely impact trade, as they are likely to increase uncertainty and costs for foreign exporters. Small and medium sized foreign companies in particular may be prevented from continuing to export to the United States for these reasons. One comment is concerned that the regulations may lead to the unintended consequence of foreign countries imposing the same requirements of U.S. goods in foreign trade. (Response) FDA considers that these foreign trade comments are now moot, given the scope of these final regulations. These final regulations do not apply to foreign persons, except foreign persons transporting food in the United States, who are treated no differently than domestic food transporters under these final regulations. FDA does not believe that foreign persons who transport food in the United States will incur additional costs as a result of these regulations, because FDA assumes that they will choose to comply with § 1.352 of this final rule by establishing and

maintaining the records already required by FMCSA. See the response to comment 82, later in this document. C. Comments on Who is Subject to This Subpart? (Proposed § 1.326) 1. General (Comment 15) Several comments seek clarification on who is covered by the proposed regulation. Comments ask if the provisions of the regulations apply to port facilities, such as warehouses, or storage and inspection facilities in land, sea, or airports that belong to private companies and government bodies for food control in the country of shipping and/or origin.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary Defense Acquisition Regulations System 32 CFR Chapter I 48 CFR Chapter 2 AGENCY: Office of the Under Secretary of Defense for Acquisition and Sustainment, Department of Defense (DoD). ACTION: Advanced notice of proposed rulemaking. SUMMARY: This document provides updated information on DoD's way forward for the approved Cybersecurity Maturity Model Certification (CMMC) program changes, designated as CMMC 2.0. CMMC 2.0 builds upon the initial CMMC framework to dynamically enhance Defense Industrial Base (DIB) cybersecurity against evolving threats. The CMMC framework is designed to protect sensitive unclassified information that is shared by the Department with its contractors and subcontractors and provide assurance that Federal Contract Information (FCI) and Controlled Unclassified Information (CUI) will be protected at a level commensurate with the risk from cybersecurity threats, including Advanced Persistent Threats. Under the CMMC program, DIB contractors will be required to implement certain cybersecurity protection standards, and, as required, perform self-assessments or obtain third-party certification as a condition of DoD contract award. DATES: November 17, 2021. ADDRESSES: Visit the updated CMMC website for CMMC 2.0 updates: <https://www.acq.osd.mil/cmmc/>. FOR FURTHER INFORMATION CONTACT: Ms. Diane Knight, Office of the Under Secretary of Defense for Acquisition and Sustainment, at 202-770-9100 or diane.l.knight10.civ@mail.mil. SUPPLEMENTARY INFORMATION: Background The CMMC program is designed to enhance DIB cybersecurity to meet evolving threats and safeguard the information that supports and enables the Warfighter. Interim Defense Federal Acquisition Regulation Supplement (DFARS) rule, Assessing Contractor Implementation of Cybersecurity Requirements (DFARS Case 2019-D041), effective November 30, 2020, implemented DFARS clause 252.204-7021, Contractor Compliance with the Cybersecurity Maturity Model Certification Level Requirement. This clause implemented the initial version of CMMC program, hereafter CMMC 1.0. CMMC 1.0 was designed to protect FCI and CUI shared with and handled by DoD contractors and subcontractors on non-federal contractor information systems. CMMC 1.0 involved five progressively advanced levels of cybersecurity standards and required that DIB contractors undergo a certification process to demonstrate compliance with the CMMC cybersecurity standards at a given level.

Guide for Security-Focused Configuration Management of Information Systems ## Guide for Security-Focused Configuration Management of Information Systems Guide for Security-Focused Configuration Management of Information Systems provides guidelines for organizations responsible for managing and administering the security of federal information systems and associated environments of operation. Configuration management concepts and principles described in this publication provide supporting information for NIST SP 800-53, Security and Privacy Controls for Federal Information Systems and Organizations. NIST SP 800-128 assumes that information security is an integral part of an organization's overall configuration management. The focus of this document is on implementation of the information system security aspects of configuration management, and as such the term security-focused configuration management (SecCM) is used to emphasize the concentration on information security. In addition to the fundamental concepts associated with SecCM, the process of applying SecCM practices to information systems is described. The goal of SecCM activities is to manage and monitor the configurations of information systems to achieve adequate security and minimize organizational risk while supporting the desired business functionality and services.

Physical access devices include keys, locks, combinations, and card readers. FURTHER DISCUSSION Identifying and controlling physical access devices (e.g., locks, badges, key cards) is just as important as monitoring and limiting who is able to physically access certain equipment. Physical access devices are only strong protection if you know who has them and what access they allow.

Physical access devices can be managed using manual or automatic processes 167 NIST SP 800-171A, pp. 47-48. 168 NIST SP 800-171 Rev. 2, p. 33.

In order to be eligible for a contract with a requirement for the CMMC Status of Level 2 (Self), the OSA must have achieved the CMMC Status of either Conditional Level 2 (Self) or Final Level 2 (Self) and have submitted an affirmation. The Level 2 self-assessment must be completed every three years and the affirmation must be completed annually following the Final CMMC Status Date. Section 170.17-CMMC Level 2 Certification Assessment and Affirmation Requirements Section 170.17 addresses how an OSC will achieve and maintain compliance with the CMMC Status of Level 2 (C3PAO). The OSC must successfully implement the security requirements listed in § 170.14(c)(3) within its Level 2 CMMC Assessment Scope as described in § 170.19(c). Successful implementation requires meeting all objectives defined in NIST SP 800-171A Jun2018 for the corresponding CMMC Level 2 security requirements. Requirements for ESPs and CSPs that process, store, transmit CUI are provided in § 170.17(c)(5) and (6). After implementation, the OSC must hire a C3PAO to perform an assessment to verify the implementation. The C3PAO will score the OSC using the scoring methodology provided in § 170.24. All objectives must be met in order for a security requirement to be considered fully implemented; in some cases, if not all objectives are met, some security requirements may be placed on a POA&M as defined in § 170.21. If the minimum score has been achieved and some security requirements are in a POA&M, the OSC has achieved the CMMC Status of Conditional Level 2 (C3PAO); if all requirements are MET as defined in § 170.24(b), the OSC has achieved the CMMC Status of Final Level 2 (C3PAO). For Conditional Level 2 (C3PAO), a POA&M closeout must be conducted within 180 days as described (printed page 83102) in § 170.21(b) or the Conditional Level 2 (C3PAO) CMMC Status will expire. After a Level 2 certification assessment, as well as after a POA&M closeout, the C3PAO will input the OSC's results into the CMMC instantiation of eMASS as described in § 170.17(a)(1)(i). After a Level 2 certification assessment, as well as after a POA&M closeout, the OSC must submit an affirmation as described in § 170.22. In order to be eligible for a contract with a requirement for the CMMC Status of Level 2 (C3PAO), the OSC must have achieved the CMMC Status of either Conditional Level 2 (C3PAO) or Final Level 2 (C3PAO) and have submitted an affirmation. The Level 2 certification assessment must be completed every three years and the affirmation must be completed annually following the Final CMMC Status Date. Section 170.18-CMMC Level 3 Certification Assessment and Affirmation Requirements Section 170.18 addresses how an OSC will achieve and maintain compliance with the CMMC Status of Level 3 (DIBCAC). The OSC must have achieved the CMMC Status of Final Level 2 (C3PAO) for information systems within the Level 3 CMMC Assessment Scope as a prerequisite to undergo a Level 3 certification assessment. The OSC must successfully

(B) From subsections (d)(1), (2), (3) and (4) (record subject's right to access and amend records) because affording access and amendment rights could alert the record subject to the investigative interest of law enforcement agencies or compromise sensitive information classified in the interest of national security. In the absence of a national security basis for exemption, records in this system may be exempted from access and amendment to the extent necessary to honor promises of confidentiality to persons providing information concerning a candidate for position. Inability to maintain such confidentiality would restrict the free flow of information vital to a determination of a candidate's qualifications and suitability. (C) From subsection (e)(1) (maintain only relevant and necessary records) because in the collection of information for investigatory purposes, it is not always possible to determine the relevance and necessity of particular information in the early stages of the investigation. It is only after the information is evaluated in light of other information that its relevance and necessity becomes clear. In the absence of a national security basis for exemption under subsection (k)(1), records in this system may be exempted from the relevance requirement pursuant to subsection (k)(5) because it is not possible to determine in advance what exact information may assist in determining the qualifications and suitability of a candidate for position. Seemingly irrelevant details, when combined with other data, can provide a useful composite for determining whether a candidate should be appointed. (D) From subsections (e)(4)(G) and (H) (publication of procedures for notifying subject of the existence of records about them and how they may access records and contest contents) because the system is exempted from subsection (d) provisions regarding access and amendment, and from the subsection (f) requirement to promulgate agency rules. Nevertheless, the Office of the Secretary of Defense has published notice concerning notification, access, and contest procedures because it may, in certain circumstances, determine it appropriate to provide subjects access to all or a portion of the records about them in this system of records. (E) From subsection (e)(4)(I) (identifying sources of records in the system of records) because identifying sources could result in disclosure of properly classified national

defense or foreign policy information, intelligence sources and methods, and investigatory techniques and procedures. Notwithstanding its proposed exemption from this requirement the Office of the Secretary of Defense identifies record sources in broad categories sufficient to provide general notice of the origins of the information it maintains in this system of records.

This document provides high level guidance that refers readers to other NIST SP documents addressed in this rule. Contractors may reference this guidance when their contracts involve IoT devices. As such, the Government assumes that a small percentage of the 28 contractors awarded a contract involving a non-cloud FIS, whose contract also involves IoT devices, may refer to this publication for direction to more detailed policy and guidance regarding the devices; However, the Government does not anticipate contractors expending significant effort reading and familiarizing themselves with the publication and considers these costs to be de minimis. iii. NIST SP 800-39. NIST SP 800-39 identifies the Government's risk management responsibilities related to information systems. All contractors awarded a contract involving a non-cloud FIS will need to be aware of the requirements of the publication to adequately support the non-cloud FIS on behalf of the Government. As such, the Government assumes all 28 contractors awarded a contract involving a non-cloud FIS will expend effort to read and become more familiar with the publication. It is estimated that a contractor will expend approximately 4 hours reading NIST SP 800-39 in year one to become more familiar with its contents. Using an average loaded wage rate of \$91.10 for FIS occupations, the total estimated labor cost for a contractor to comply with NIST SP 800-39 is approximately \$370 (4 hours * \$91.10). iv. NIST SP 800-37. Contractors will reference this guidance to develop a high-level process to manage system risk through preparation, categorization, control selection, control implementation and assessment, system authorizations, and continuous monitoring. This guidance applies to contracts involving a custom-build system. As such, the Government assumes all 6 contractors awarded a contract involving a custom-build, non-cloud FIS will expend effort to comply with this guidance. It is estimated that, in year one, a contractor will expend approximately 8 hours reading and ensuring the processes they develop incorporate the high-level guidance of NIST SP 800-37. Using an average loaded wage rate of \$91.10 for FIS occupations, the total estimated labor cost for a contractor to comply with NIST SP 800-37 is approximately \$730 (8 hours * \$91.10). v. NIST SP 800-207. Contractors will reference this guidance when designing a zero-trust architecture approach for a system. This guidance applies to contracts involving a custom-build system; However, this document is very high level and applies to custom-build requirements in limited circumstances. For these reasons, the Government does not anticipate most contractors needing to read and familiarize themselves with the publication, as its application is unlikely in most custom-build contracts and, in such circumstances, any time spent reviewing the guidance will be very minimal. vi. NIST SP 800-160, Volume 1.

3.2.7 | Unknowns of Data Collection | 17 | | 3. 3.2.7 Unknowns of Data Collection About 40% of participants were concerned that they did not have a good grasp on smart home device data collection and usage, which led to privacy concerns.

Although portions of some records may be denied, the remaining reasonably segregable portions must be released to the requester. Unless disclosing the extent of the deletion would harm an interest protected by an exemption, the amount of deleted information shall be indicated on the released portion of paper records by use of brackets or darkened areas. In no case shall the deleted areas be left white without the use of brackets to show the bounds of deleted information. In the case of electronic deletion or deletion in audiovisual or microfiche records, if technically feasible, the amount of redacted information shall be indicated at the place in the record such deletion was made, unless including the indication would harm an interest protected by the exemption under which the deletion was made. This may be done by use of brackets, shaded areas, or some other identifiable technique that will clearly show the limits of the deleted information. (d) Response to requester. (1) When a decision is made to release a record, a copy should be made available promptly to the requester. (2) When a request for a record is denied in whole or in part, the official designated to respond shall provide the requester a written explanation of the substantive basis for denial including specific citation of the statutory exemption applied under provisions of this part (e.g., 5 U.S.C. 552 (b)(1)) and advise the requester of their appeal rights, including the address to which any appeal should be mailed. The basis for the determination shall be in sufficient detail to permit the requester to make a decision concerning an appeal. If the IDA does not sign the response letter, the name and duty title of the IDA will be specified in the letter. The official also shall advise the requester that any appeal to the adverse determination must be postmarked no later than

60 days after the date of the initial denial letter. (3) The DoD Component shall make a reasonable effort to estimate the volume of the records denied and provide this estimate to the requester, unless providing such an estimate would harm an interest protected by an exemption of the FOIA. This estimate should be in number of pages or in some other reasonable form of estimation. (4) When a denial is based on a statute qualifying as a FOIA Exemption 3 statute, the DoD Components shall state the particular statute relied upon to deny the information. (5) When a requester is assessed fees for processing a request, the requester's fee category shall be specified in the final response letter. The DoD Components also shall provide the requester with a complete cost breakdown (e.g., 15 pages of office reproduction at \$.15 per page; three hours of professional level search at \$53.00 per hour, etc.) in the response letter. (e) File of initial denials.

) (applying privacy provisions and penalties to business associates of covered entities). The Department codified the term "covered entity" and defined it using these three categories of persons. 45 CFR 164.103 . Back to Citation 37. 42 U.S.C. 1320d-2(d)(2) . Back to Citation 38. 42 U.S.C. 1320d-2(d)(2)(A) . Back to Citation 39. 42 U.S.C. 1320d-2(d)(2)(B) . Back to Citation 40. 42 U.S.C. 1320d-2(d)(2)(C) . Back to Citation 41. "Sec. 262(a) of Public Law 104-191 , 110 Stat. 2024, adding sec. 1173(a) (codified at 42 U.S.C. 1320d-2(a)(1)) . Back to Citation 42. "Sec. 262(a) of Public Law 104-191 , 110 Stat. 2025, adding sec. 1173(d) (codified at 42 U.S.C. 1320d-2(d)) . Back to Citation 43. "Sec. 262(a) of Public Law 104-191 , 110 Stat. 2026, adding sec. 1174(a) (codified at 42 U.S.C. 1320d-3(a)) . Back to Citation 44. "Sec. 262(a) of Public Law 104-191 , 110 Stat. 2025, adding sec. 1173(d)(1) (codified at 42 U.S.C. 1320d-2(d)(1)) . Back to Citation 45. Id. Back to Citation 46. "Sec. 262(a) of Public Law 104-191 , 110 Stat. 2026, adding sec. 1174(b)(1) (codified at 42 U.S.C. 1320d-3) . Back to Citation 47. "Sec. 1102 of the SSA (codified at 42 U.S.C. 1302) . Back to Citation 48. "Sec. 262(a) of Public Law 104-191 , 110 Stat. 2023, adding sec. 1172 (codified at 42 U.S.C. 1320d-1) . Back to Citation 49. Id. Back to Citation 50. "Title XIII of Division A and title IV of Division B of ARRA of 2009, Public Law 111-5 , 123 Stat. 115 (Feb. 17, 2009) (codified at 42 U.S.C. 201 note) . Back to Citation 51. Id.; see also Subtitle B of title XIII of the HITECH Act (codified at 42 U.S.C. 17911-17912) , 42 U.S.C. 300jj-31-38 . Back to Citation 52. " See H.R. Rep. No. 111-7, at 74 (2009), accompanying H.R. 629, 111th Cong. Back to Citation 53. "H.R. 629, Energy and Commerce Recovery and Reinvestment Act of 2009, introduced in the House on Jan. 22, 2009, contained nearly identical provisions to subtitle D of the HITECH Act. Back to Citation 54. "C. Stephen Redhead, "The Health Information Technology for Economic and Clinical Health (HITECH) Act," Congressional Research Service, p. 8 (2009), <https://crsreports.congress.gov/product/pdf/R/R40161/9> ; id. at 9 ("[Health IT], which generally refers to the use of computer applications in medical practice, is widely viewed as a necessary and vital component of health care reform."). Back to Citation 55. "Subtitle D of title XIII of the HITECH Act (codified at 42 U.S.C. 17921 , 42 U.S.C. 17931-17941 , and 42 U.S.C. 17951-17953) . Back to Citation 56. " See S. Rept. 111-3, 111th Cong. accompanying S. 336, 111th Cong., at 59 (2009). Back to Citation 57. "Sec. 13401 of Public Law 111-5 , 123 Stat. 260 (codified at 42 U.S.C. 17931) . Back to Citation 58. "Sec. 13401(a) of Public Law 111-5 , 123 Stat. 260 (codified at 42 U.S.C. 17931) . Back to Citation 59. "Sec. 13401(c) of Public Law 111-5 , 123 Stat. 260 (codified at 42 U.S.C. 17931) . Back to Citation 60. "Sec. 13421(b) of the HITECH Act (codified at 42 U.S.C. 17951) . Back to Citation

The DoD disagreed with the commenter's assertion that Assessors are robotic. Assessors will go through CMMC training and will assess each unique CMMC Assessment Scope, as defined by the OSA, against the security requirements. As specified in § 170.13(a) CCPs can participate on CMMC Level 2 certification assessments with CCA oversight where the CCA makes all final decisions. Updates to training are beyond the scope of this rule. Statements made in training materials produced prior to final adoption of the CMMC rule are beyond the scope of CMMC rulemaking. DoD disagrees with the comment that § 170.13 does not provide sufficient detail regarding the role CCPs may play in an assessment. The requirement in the rule that "with CCA oversight where the CCA makes all final determinations" provides sufficient flexibility to adapt to a wide variety of assessments while ensuring the responsibility for assessment findings rests with the CCA and Lead CCA. The rule restates COI and CoPC requirements in each ecosystem section because all CMMC ecosystem members are required to abide by the appropriate ethics and conflicts of interest policies established by the CMMC AB and the CAICO. Rule content pertaining to ethics, quality assurance functions, record keeping, data encryption, security, and other functions across the ecosystem are tailored to reflect the role each entity fills in the ecosystem. DoD CIO, in coordination with OUSD/I&S, evaluated the

requirements for the CMMC Ecosystem. Based on the access to sensitive unclassified information, a Tier 3 background investigation that results in determination of national (printed page 83124) security eligibility is required. § 170.13(a) states that a CCP is eligible to participate in Level 2 certification assessment with CCA oversight and is eligible to become a CCA and will receive additional training and testing per the requirements in § 170.11. The phased implementation plan described in § 170.3(e) is intended to address ramp-up issues and provide time to train the necessary number of assessors. DoD has updated the rule to add an additional six months to the Phase 1 timeline. e. CCI 1. Training and Training Materials Comment: One comment mistook the requirement to ·provide all documentation and records in English· as applying to training materials. Four comments expressed concerns about the requirements for confidentiality surrounding training records. These concerns arose primarily from a misinterpretation of the requirement to ·keep confidential all information obtained during the performance of CMMC training activities· to mean a requirement to keep the training materials themselves confidential, rather than keeping student records confidential. Response:

be reasonable and appropriate for the type of user or technology asset, the electronic information system or technology asset to which access is sought, and the type of information maintained on such information system or technology asset. For example, a regulated entity may determine that any authentication failure of an administrative privileged access account should disable the account because of the level of risk compared to an authentication failure of a non-administrative privileged account. The Department does not propose to define disable or suspend and relies upon the industry understanding that disabling a user's access would require intervention to restore the capability to use the user identity, while a suspension may prevent additional log-in attempts for a temporary, limited period of time. Consistent with NCVHS' recommendation and existing guidance, the Department also proposes to add an implementation specification for network segmentation at 45 CFR 164.312(a)(2)(vi) that would require a regulated entity to deploy technical controls to segment its relevant electronic information systems in a reasonable and appropriate manner. [712] Under this proposal, a regulated entity with multiple, distinct electronic information systems would be required to separate relevant electronic information systems using reasonable and appropriate technical controls. Network segmentation is a physical or virtual division of a network into multiple segments, creating boundaries between the operational and IT networks to reduce risks, such as threats caused by phishing attacks. [713] For example, where a regulated entity operates both a point-of-sale system and an EHR on the same network, the EHR could be compromised through a successful attack by an intruder moving laterally (i.e., within the same network) from a previously compromised point-of-sale system because the intruder's movements were not impeded by network segmentation. Accordingly, we believe that it is appropriate to require regulated entities to deploy technical controls to segment the networks to which their relevant electronic information systems are connected. [714] What constitutes reasonable and appropriate network segmentation depends on the regulated entity's risk analysis and how it has implemented its network(s) and relevant electronic information systems. This proposed new implementation specification aligns with the Department's enhanced CPG for Network Segmentation because where the CPG is implemented, an intruder's ability to freely move within a regulated entity's network and protect ePHI is minimized. [715] The proposed implementation specification for data controls at proposed 45 CFR 164.312(a)(2)(vii) would require a regulated entity to deploy technical controls to allow access to ePHI based on the regulated entity's policies and procedures for granting users and technology assets access relevant electronic information systems as specified in proposed 45 CFR 164.308(a)(10)

To further elaborate the DoD established a review body that evaluated the CMMC Program to ensure it was meeting the programmatic requirements to secure Controlled Unclassified Information within the non-Federal networks of the Defense Industrial Base. A special independent team was established to review and provide recommendations on improving the program. The DoD determined that the CMMC program should only employ the Cybersecurity Standards prescribed by the NIST SP 800-171 that had been required for defense contractors since 2017 as implemented by the DFARS clause 252.204-7012, which resulted in the removal of 20 requirements aligned with cybersecurity maturity. The ESG also recommended simplifying the program structure to require only 3 levels of certification vice the original 5. The program further determined that certifications should not be required at CMMC Level 1 and that self-assessment with an annual affirmation was sufficient for this level. Level 2 CMMC was further evaluated and determined that bifurcation of this level was appropriate, and some CUI would only require a Level 2 self-assessment with annual affirmation, which further reduced the

costs for the program. Further the ESG recommended that Plans of Actions and Milestones (POA&Ms) for lower-level requirements that were not met be allowed for a limited period of time. This rule was updated to allow POA&Ms for no more than 180 days to give contractors the ability to achieve contract award without being fully compliant with all requirements of NIST SP 800-171 R2. And, in another effort to minimize the economic impact the program developed a Phase-in approach to incrementally implement CMMC in four phases over 4 years, with the first year being focused on Self-assessment and compliance with NIST SP 800-171 R2 giving contractors more time to implement the requirements already required in their contracts since 2017. A CMMC waiver process was also included in the program which allows DoD the discretion to waive CMMC Program requirements to a procurement or class of procurements in advance of the solicitation in accordance with all applicable policies, procedures, and approval requirements. This waiver would allow contract award and the contractor would be expected to achieve compliance and certification at a defined time post-award. The DoD is employing a phased approach to the CMMC rollout to reduce implementation risk. DoD expects that the public has utilized the lead-time prior to the publication of this rule to prepare for CMMC implementation. CMMC Program requirements make no changes to existing policies for information security requirements implemented by the DoD.

No changes were made to quotations from sources outside the rule. A definition cited from a source must exactly match the source, it cannot be altered. To address a commenter's misperception that the rule does not reference existing FAR/DFARS, or other DoD authoritative sources, it should be noted that the CMMC proposed rule includes 54 mentions each of FAR clause 52.204-21 and DFARS clause 252.204-7012. The DFARS clause 252.204-7012 is added to DoD contracts to implement the requirements of NIST SP 800-171, which is the authoritative reference for adequate safeguarding of CUI. Contractors complying with CMMC need to be familiar with those documents that are incorporated by reference, which address requirement-related topics. NIST SP 800-53 R5 is incorporated by reference only for applicable definitions because DoD chose to use the latest definitions available. The purpose of a reference listed in § 170.2 should be interpreted based on the context in which it is used. For example, the references provided in § 170.4 specify the source of the definition. The references for the CMMC Assessments Guides listed in Appendix A have been updated. These guides are largely derived from NIST SP 800-171 R2, NIST SP 800-171A Jun2018, NIST SP 800-172 Feb2021, and NIST SP 800-172A Mar2022. The DoD has updated § 170.3 to align with the FAR terminology and now reflects 'Federal Information System' instead of 'Government Information System'. The DoD updated the rule to reference the latest version of 'Cloud Security Technical Reference Architecture' and, where appropriate, to identify a revision number for NIST SP 800-171. Specific details of cybersecurity-related resources and training developed to support the DIB are outside the scope of this rule. As it becomes available, supporting resources and training information will be disseminated. Currently, multiple public resources are available to help educate companies on NIST and CMMC requirements. The DoD declined to respond to comments based on comparison of pre-publication draft versions of the supplemental guidance documents. A commenter's claim that DoD views the CMMC program as only addressing 'basic cybersecurity' is incorrect. Throughout the rule, references to 'basic safeguarding' mean the requirements of CMMC Level 1, which align directly to the requirements of FAR clause 52.204-21. That FAR clause is titled 'Basic Safeguarding of Covered Contractor Information Systems'. Similarly, the CMMC program establishes a CMMC Level 3 requirement to comply with a subset of requirements from NIST SP 800-172 Feb2021, titled, 'Enhanced Security Requirements for Protecting Controlled Unclassified Information'. Section 170.4 includes acronyms and definitions used in the rule text. Terms from other authoritative sources are listed in § 170.4 and are properly sourced. 1 CFR part 51 governs drafting of this rule. The DoD updated the rule throughout to reflect new terminology better differentiating between the activity of (

(7) Ensure policies and administrative processes within their directorates are evaluated to ensure compliance with the procedures in this part. (h) System Managers. System Managers will: (1) Report any changes to their existing SORN(s) to the Chief of the OIP for publishing in the FR at least 90 working days before the intended change to the system. (2) Review their published SORN(s) on a biennial basis and submit updates to the Chief of the OIP as necessary. (3) Ensure appropriate training is provided for all users, to include contractors, which have access to records covered by their published system notice. (4) Ensure safeguards are in place to protect all records containing PII (electronic, paper, etc.) from unauthorized access, use, disclosure, alteration, and/or destruction using guidelines found in 32 CFR part 310, subpart B, 32 CFR part 310, Appendix 1, and DoDM 5200.01, Volume 4. (5) Assist in responding to any complaints and inquiries regarding the collection or maintenance of, or access to information covered by their published SORN(s). (6)

Process all 5 U.S.C. 552a requests for access and amendment, as outlined in section 6 of 32 CFR part 329 . (7) Maintain a record of disclosures for any records covered by a SORN using a method that complies with 32 CFR part 310, subpart E when disclosing records outside of the agency (DoD). Such disclosures will only be made when permitted by a Routine Use published in the SORN. (i) As required by 5 U.S.C. 552a and 32 CFR part 310, subpart E , the disclosure accounting will be maintained for 5 years after the disclosure, or for the life of the record, whichever is longer. The record may be maintained with the record disclosed, or in a separate file within the office's official record keeping system. (ii) Pursuant to 5 U.S.C. 552a and 32 CFR part 310, subpart E , the disclosure accounting will include the release date, a description of the information released, the reason for the release; and, the name and address of the recipient. § 329.6 Procedures. (a) Publication of Notice in the FR. (1) A SORN shall be published in the FR of any record system meeting the definition of a SOR, as defined by 5 U.S.C. 552a . (2) System Managers shall submit notices for new or revised SORNs through their Director to the Chief of the OIP for review at least 90 working days prior to implementation. (3) The Chief of the OIP shall forward complete SORNs to the Defense Privacy and Civil Liberties Office (DPCLO), or the respective service that has the statutory authority to publish the SORN, for review and publication in the FR in accordance with 32 CFR part 310, subpart G . Following the OMB comment period, the public is given 30 days to submit written data, views, or arguments for consideration before a SOR is established or modified. (b) Access to Systems of Records Information. (1) As provided by 5 U.S.C. 552a

From the NIST SP 800-172 Rev 3 Final Public Draft: Audit and Accountability 831 03.0 3.01E Protection of Audit Record Storage in Separate Physical Systems or Components Store audit records in a repository that is part of a physically different system or system component than the system or component being audited. DISCUSSION Storing audit records in a repository that is separate from the audited system or system component helps to ensure that a compromise of the system being audited does not also result in a compromise of the audit records. Storing audit records on separate physical systems or components preserves the confidentiality, integrity, and availability of audit records and facilitates the management of audit records as an organization-wide activity. Storing audit records on separate systems or system components applies

to the extent that such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now maintained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy; to avoid interference during the conduct of criminal, civil, or administrative actions or investigations; to ensure protective services provided the President and others are not compromised; to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations; to preserve the confidentiality and integrity of Federal testing materials; and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (24) System identifier and name. DPFPA 06, Internal Affairs Records System. (i) Exemption. Portions of this system that fall within 5 U.S.C. 552a(j)(2) and/or (k)(2) are exempt from the following provisions of 5 U.S.C. 552a , section (c)(3) and (4); (d); (e)(1) through (e)(3); (e)(4)(G) through (I); (e)(5); (f) and (g) of the Act, as applicable. (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(2) . (iii) Reasons. (A) From subsections (c)(3) and (4) because making available to a record subject the accounting of disclosure of investigations concerning him or her would specifically reveal an investigative interest in the individual. Revealing this information would reasonably be expected to compromise open or closed administrative or civil investigation efforts to a known or suspected offender by notifying the record subject that he or she is under investigation. This information could also permit the record subject to take measures to impede the investigation, e.g. destroy evidence, intimidate potential witnesses, or flee the area to avoid or impede the investigation.

HIPAA Security Rule section 164.310 (Physical Safeguards) addresses workstation use. Covered entities and business associates must implement appropriate safeguards to protect electronic protected health information (ePHI). For workstation use, organizations should: 1. Establish and document policies specific to workstation use 2. Implement technical and procedural controls 3. Train workforce members on their responsibilities 4. Conduct periodic risk assessments addressing workstation use 5. Maintain documentation of compliance efforts Under 45 CFR 164.310, this is a physical safeguards requirement that applies to all covered entities and business associates that

create, receive, maintain, or transmit ePHI.

Removing ·DIB participants' capabilities· and adding in its place ·DIB CS Program participants' capabilities·. §-236.2 [Amended] 4. Amend §-236.2 by: a. Removing the definition of ·Access to media·. b. In the definition of ·DIB participant·: i. Removing ·DIB participant· and adding in its place ·DIB CS Program participant·. ii. Removing ·DIB CS program· and adding in its place ·DIB CS Program·. c. Removing ·DIB CS program· in the definition of ·Government furnished information (GFI)· and adding in its place ·DIB CS Program·. §-236.3 [Amended] 5. Amend §-236.3 by: a. Removing ·program· and adding in its place ·Program participants· in paragraph (b)(1). b. Removing ·DIB CS program· and adding in its place ·DIB CS Program· in paragraph (c). 6. Amend §-236.4 by: a. Removing · http · and adding in its place · https · in paragraphs (b)(2), (c), and (d). b. Removing · http://iase.disa.mil/pki/eca/Pages/index.aspx · and adding in its place · https://public.cyber.mil/eca/ · in paragraph (e). c. Revising paragraph (f). d. Adding a comma after ·as appropriate· in the first sentence in paragraph (g). e. Removing ·paragraph (e)· and adding in its place ·paragraph (i)· in paragraph (k). f. In paragraph (m)(4): i. Removing ·DIB contractors· and adding in its place ·defense contractors·. ii. Removing ·DIB CS program· and adding in its place ·DIB CS Program·. g. Revising paragraph (p). The revisions read as follows: §-236.4 Mandatory cyber incident reporting procedures. * * * * * (f) Third-party service provider support. If the contractor utilizes a third-party service provider (SP) for information system security services, the contractor may authorize the SP to report cyber incidents on behalf of the contractor. * * * * * (p) Freedom of Information Act (FOIA). Agency records, which may include qualifying information received from non-Federal entities, are subject to request under the Freedom of Information Act (5 U.S.C. 552). The Government will notify the non-Government source or submitter (e.g., contractor or DIB CS Program participant) of the information in (printed page 27838) accordance with the procedures in 32 CFR 286.10 . * * * * * 7. Amend §-236.5 by: a. Revising section heading and paragraph (a). b. In paragraph (b): i. Removing ·DIB CS program· and adding in its place ·DIB CS Program·. ii. Removing ·DIB participant· and adding in its place ·DIB CS Program participant·. c. In paragraph (c): i. Removing ·DIB participant· and adding in its place ·DIB CS Program participant·. ii. Removing ·individual DIB participants· and adding in its place ·individual DIB CS Program participants·. d. In paragraph (d): i. Removing ·DoD's DIB CS Program Office· and adding in its place ·DoD's DIB CS Program Management Office·. ii. Removing ·DoD DIB· and adding in its place ·DoD-DIB·. iii. Removing ·DIB CS program· and adding in its place ·DIB CS Program·. e. Removing ·DIB participants· and adding in its place ·DIB CS Program participants· in paragraph (e). f. Redesignating paragraphs (f) through (n) as paragraphs (g) through (o). g. Adding new paragraph (f). h.

CMMC Acquisition rule also partially implements a section of the National Defense Authorization Act for Fiscal Year 2020 directing the Secretary of Defense to develop a consistent, comprehensive framework to enhance cybersecurity for the U.S. defense industrial base. [5] The 48 CFR part 204 CMMC Acquisition rule, when finalized, will allow DoD to require a specific CMMC level in a solicitation or contract. When CMMC requirements are applied to a solicitation, Contracting officers will not make award, exercise an option, or extend the period of performance on a contract, if the offeror or contractor does not have the passing results of a current certification assessment or self-assessment for the required CMMC level, and an affirmation of continuous compliance with the security requirements in the Supplier Performance Risk System (SPRS) [6] for all information systems that process, store, or transmit FCI or CUI during contract performance. Furthermore, the appropriate CMMC certification requirements will flow down to subcontractors at all tiers when (printed page 83093) the subcontractor processes, stores, or transmits FCI or CUI. It should be noted the Department may include CMMC requirements on contracts awarded prior to 48 CFR part 204 CMMC Acquisition rule becoming effective, but doing so will require bilateral contract modification after negotiations. To date, the DoD has relied on offeror representation that the security requirements of National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171, · Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations· have been met, as described by 48 CFR 252.204-7008 . In some instances, the DoD has verified contractor implementation of NIST SP 800-171 through assessment by the Defense Contract Management Agency (DCMA) Defense Industrial Base Cybersecurity Assessment Center (DIBCAC). As part of this responsibility, DCMA DIBCAC assesses DIB companies to ensure they are meeting contractually required cybersecurity standards and to ensure contractors have the ability to protect CUI for government contracts they are awarded. DCMA DIBCAC conducts NIST SP 800-171 assessments in support of 48 CFR 252.204-7012 (DFARS clause 252.204-7012), Safeguarding Covered Defense Information and Cyber

Incident Reporting, [7] and 48 CFR 252.204-7020 (DFARS clause 252.204-7020), NIST SP 800-171 DoD Assessment Requirements. [8] The DCMA DIBCAC prioritization process is designed to adjust as DoD's cyber priorities evolve based on ongoing threats. DCMA DIBCAC collects and analyzes data on DoD contractors to include: Mission critical programs, technologies, and infrastructure and the contractors (prime or lower tier) that support DoD capabilities. Cyber threats, vulnerabilities, or incidents. DoD Leadership requests. To date, DCMA DIBCAC has assessed 357 entities including DoD's major prime contractors. In accordance with NIST SP 800-171, titled ·

to notify its business associate when it has activated its contingency plan. Additionally, the Department proposes conforming changes to the references of 45 CFR 164.308(b) throughout 45 CFR 164.314 consistent with proposals made to modify 45 CFR 164.308(b) . The Department does not intend these to be substantive changes, but rather an alignment with the proposed structural modifications in 45 CFR 164.308(b) . As discussed above, the Department proposes to remove the term ·required· from the implementation specification at 45 CFR 164.314(a)(2) consistent with its proposal to eliminate the distinction between addressable and required implementation specifications. We also propose a few miscellaneous non-substantive corrections to update citations in the standard at 45 CFR 164.314(a)(1)(i) and (a)(2)(iii) . We do not believe that these technical amendments would add or change any regulatory, recordkeeping, or reporting requirements, nor would they change the Department's interpretation of any regulation. 2. Section 164.314(b)(1)-Standard: Requirements for Group Health Plans a. Current Provision The second standard in 45 CFR 164.314 requires that, except when ePHI disclosed to a plan sponsor is summary health information [845] or enrollment or disenrollment information, [846] group health plan [847] documents must provide that the plan sponsor will reasonably and appropriately safeguard ePHI created, received, maintained, or transmitted to or by the plan sponsor on behalf of the group health plan. Section 164.314(b)(2) requires that the plan documents of a group health plan must be amended to incorporate provisions to require the plan sponsor to: Implement reasonable and appropriate administrative, physical, and technical safeguards to protect the confidentiality, integrity, and availability of the ePHI that it creates, receives, maintains, or transmits on behalf of the group health plan. [848] Ensure that the separation between the group health plan and plan sponsor required by the Privacy Rule at 45 CFR 164.504(f)(2)(iii) [849] is supported by reasonable and appropriate security measures. [850] Ensure that any agent to whom it provides ePHI, agrees to implement reasonable and appropriate security measures to protect the information. [851] Report to the group health plan any security incident of which it becomes aware. [852] b. Issues To Address Plan sponsors are not directly liable for compliance with the Security Rule because they are not regulated entities, i.e., covered entities or business associates under HIPAA. Therefore, plan sponsors' obligations to apply safeguards to ensure the confidentiality, integrity, and availability of ePHI are limited to the requirements set forth in the plan documents of its group health plan. While 45 CFR 164.314(b)

One issue related to report and risk analysis stems from the difficulty in collating, normalizing and interpreting different reports and risk assessments due to the wide variety of security-related definitions, semantics, nomenclature and metrics used by different test tools. For example, one test tool may classify the estimated risk for using an app as low, moderate, high or severe risk, while another may classify the estimated risk as pass, warning or fail. While some standards exist for expressing risk assessment 15 and vulnerability reporting 16 the current adoption of these standards by test tools is low. To the extent possible, it is recommended that an organization use test tools that leverage vulnerability reporting and risk assessment standards. If this approach is not possible, it is recommended that the organization provide sufficient training to analysts on the interpretation of reports and risk assessments generated by test tools.

(g) A subcontractor requiring access to classified information under a contract shall be identified with a Commercial and Government Entity (CAGE) code on the DD Form 254. A subcontractor requiring access to classified information shall provide its CAGE code with its name and address or otherwise include it prominently in the proposal. Each location of subcontractor performance listed on the DD Form 254 is required to reflect a corresponding unique CAGE code for each listed location unless the work is being performed at a Government facility, in which case the agency location code shall be used. The CAGE code must be for that name and address. Insert the word ·CAGE· before the number. The CAGE code is required prior to award. * * * * * 10. Amend section 52.204-17 by revising the provision title and date and removing from paragraph (a)(1) ·entity; or· and adding ·entity by unique location; or· in its place. The revision reads as follows: 52.204-17 Ownership or Control

of Offeror. * * * * * Ownership or Control of Offeror ([DATE]) * * * * * 11. Amend section 52.204-18 by: a. Revising the date of the clause; b. Removing from paragraph (a)(1) ·entity; or· and adding ·entity by unique location; or· in its place; c. Removing from paragraph (b) ·DLA· and adding ·Defense Logistics Agency (DLA· in its place, and removing from paragraph (d) ·NSPA· and adding ·North Atlantic Treaty Organization (NATO) Support and Procurement Agency (NSPA)· in its place; and d. Adding Alternate I. The revision and addition read as follows: 52.204-18 Commercial and Government Entity Code Maintenance. * * * * * Commercial and Government Entity Code Maintenance ([DATE]) * * * * * Alternate I ([DATE]). As prescribed at 4.1804(c), add the following additional paragraph (f). (f) Contractors shall ensure that subcontractors maintain their CAGE code(s) throughout the life of the contract. 12. Amend section 52.204-20 by revising the date of the provision and (printed page 33205) removing from paragraph (a)(1) ·entity; or· and adding ·entity by unique location; or· in its place. The revision reads as follows: 52.204-20 Predecessor of Offeror. * * * * * Predecessor of Offeror ([DATE]) * * * * * PART 53-FORMS 13. Amend section 53.204-1 by revising the introductory text to read as follows: 53.204-1 Safeguarding classified information within industry (DD Form 254, DD Form 441). The following forms, which are prescribed by the Department of Defense, shall be used by DoD components and those nondefense agencies with which DoD has agreements to provide industrial security services for the National Industrial Security Program if contractor access to classified information is required, as specified in subpart 4.4 and the clause at 52.204-2: * * * * * [FR Doc. 2019-14379 Filed 7-11-19; 8:45 am] BILLING CODE 6820-EP-P

Because small businesses typically don't have the resources to invest in information security the way larger businesses can, many cyber criminals view them as soft targets. Your small business may have money or information that can be valuable to a criminal; your computer may be compromised and used to launch an attack on somebody else (i.e., a botnet), or your business may provide access to more high-profile targets through your products, services, or role in a supply chain. - Environmental (e.g. fire, water, tornado, earthquake); - Business Resources (e.g. equipment failure, supply chain disruption, employees), and - Hostile Actors (e.g. hackers, hacktivists, criminals, nation-state actors). You should review and update your risk management plan at least annually and whenever you may be considering any changes to the business (e.g. beginning a new project, a change in procedure, or purchasing a new IT system). Also, if you hear that something happened to one of your business partners, suppliers (including makers of any computer equipment or software you may use), customers, or employees, use this exercise to make sure you are still adequately protected.

The relational expression $age > 18$; within the policy can be viewed as a Boolean expression; age has values that will evaluate to true (values greater than 18), and those which will evaluate to false (values less than or equal to 18). The software takes the input policy and replaces the relational expressions with temporary Boolean variables. After the replacement, the software processes the input policy normally. Then the software will solve each relational problem to find values that pass and fail, and updates the results with those values as shown in Figure 32.

5 U.S.C. 601 , et seq., because the rule creates minimal requirements. The initial regulatory flexibility analysis (IRFA) has been prepared and is summarized as follows: DoD, GSA, and NASA are proposing to amend the Federal Acquisition Regulation (FAR) to require electronic submission of the DD Form 254, Contract Security Classification Specification. The objective of this proposed rule is to revise the FAR to update and clarify the requirements for using the DD Form 254, Contract Security Classification Specification. The Government uses the DD Form 254 to convey security requirements to contractors when contract performance requires access to classified information. Prime contractors also use the DD Form 254 to convey security requirements to subcontractors that require access to classified information to perform on a subcontract. Subcontractors may also use the DD Form 254 if access to classified information is required to convey security requirements to additional subcontractors. DoD, GSA, and NASA do not expect that this proposed rule will have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601 , et seq. The proposed rule would apply to small businesses awarded contracts or subcontracts by Executive agencies covered by the National Industrial Security Program that require access to classified information. Currently, the Defense Security Service monitors approximately 13,500 contractor facilities that are cleared for access to classified information. Approximately 9,000 facilities are considered less-complex, which includes small businesses and smaller security operations. Subject matter experts estimate that 5,400 (60 percent) of the 9,000 less-complex facilities are small businesses. The proposed rule does not

impose any Paperwork Reduction Act reporting, recordkeeping, or other compliance requirements on any small entities. The proposed rule does not impose any new reporting, recordkeeping or other compliance requirements. The rule does not duplicate, overlap, or conflict with any other Federal rules. There are no significant alternatives to the rule which accomplish the stated objectives of applicable statutes and which minimize any significant economic impact of the rule on small entities. The Regulatory Secretariat Division has submitted a copy of the IRFA to the Chief Counsel for Advocacy of the Small Business Administration. A copy of the IRFA may be obtained from the Regulatory Secretariat Division. DoD, GSA and NASA invite comments from small business concerns and other interested parties on the expected impact of this rule on small entities. DoD, GSA, and NASA will also consider comments from small entities concerning the existing regulations in subparts affected by this rule consistent with 5 U.S.C. 610 . Interested parties must submit such comments separately and should cite 5 U.S.C. 610 (FAR Case 2015-002) in correspondence. VII. Paperwork Reduction Act

(iii) A contractor may give an employee access to classified information at the same or lower level of classification as the level of the contractor's entity eligibility determination if the employee has: (A) A valid need-to-know for the classified information. (B) A USG favorable eligibility determination for access to classified information at the appropriate level; and (C) Signed a non-disclosure agreement. (2) The CSA will determine eligibility for access to classified information in accordance with SEAD 4 (available at: <https://www.dni.gov/files/NCSC/documents/Regulations/SEAD-4-Adjudicative-Guidelines-U.pdf>) and notify the contractor when eligibility has been granted. (i) The CSA will notify the contractor when an employee's eligibility has been denied, suspended, or revoked. (ii) The contractor will immediately deny access to classified information to any employee when notified of a denial, revocation, or suspension of eligibility regardless of the contractor employee's location. (iii) If the employee's performance is at a USG facility, the contractor will provide notification to the appropriate GCA of any denial, revocation, or suspension of eligibility for access to classified information. (3) Contractors will annotate and maintain the accuracy of their employees' records in the system of record for contractor eligibility and access to classified information, when one has been designated by the CSA. (4) Within an MFO or within the same business organization, contractors may centrally manage eligibility for access to classified information and access to classified information records. (5) The contractor will limit requests for determinations of eligibility for access to classified information to the minimum number of employees and consultants necessary for operational efficiency in accordance with contractual obligations and other requirements of this rule. Requests for determinations of eligibility for access to classified information will not be used to establish a cache of cleared employees. (6) The contractor will not submit a request for an eligibility determination to one CSA if the employee applicant is known to be cleared or in process for eligibility for access to classified information by another CSA. In such cases, reciprocity of eligibility determination in accordance with SEAD 7 (available at: https://www.dni.gov/files/NCSC/documents/Regulations/SEAD-7_BI_ReciprocityU.pdf) shall be used. The contractor will provide the new CSA with the full name, date, and place of birth, social security number, clearing agency, and type of investigation for verification. (7) Contractors will not submit requests for determination of eligibility for access to classified information for individuals who are not their employees or consultants; nor will they submit requests for employees of subcontractors.

The Department proposes to add and define the term 'technical controls' to help regulated entities better understand what we mean by technical safeguards for purposes of complying with the Security Rule. We propose to define technical controls as technical mechanisms contained in the hardware, software, or firmware components of an electronic information system that are primarily implemented and executed by the electronic information system to protect it and the data within the electronic information system. The Department believes that adding this term would better convey the expectation that a regulated entity is (printed page 929) required to deploy technical safeguards across its enterprise by, among other things, configuring and using technical mechanisms in the hardware, software, and firmware components of its relevant electronic information systems to protect ePHI and electronic information systems that create, receive, maintain, or transmit ePHI or that otherwise affect the confidentiality, availability, or integrity of ePHI. 17. Modifying the Definition of 'Technical Safeguards' a. Current Provision and Issues To Address The current definition of 'technical safeguards' includes the technology and policy and procedures for its use that protect ePHI and control access to it. [390] As discussed above, the Department believes

that there is an immediate need to modernize and update the definition to better reflect the role technology plays in protecting ePHI and the technical components of information systems, versus the role of policies and procedures. This would complement our effort to clarify the relationship between technology and the implementation of technical policies and procedures. b. Proposal The Department proposes to modify the definition of technical safeguards to expressly include technical controls. We also propose to add language that would clarify that the technology, technical controls, and related policies and procedures in this category govern the use of the technology to protect and control access to ePHI. The proposed changes also would improve the consistency of language across the safeguard provisions and rule. 18. Adding a Definition of Technology Asset a. Issues To Address Throughout the Security Rule, standards and implementation specifications list the components of electronic information systems to which its requirements apply. Based on the Department's enforcement experience, we believe that it would be beneficial to more clearly distinguish between the requirements that apply to all components of an electronic information system and those that only apply to certain components. Additionally, we believe it would be beneficial to distinguish between requirements that apply specifically to each particular component of an electronic information system and those that apply to the electronic information system as a whole. b. Proposal

IR.L2-3.6.1 Incident Handling CMMC Assessment Guide Level 2 | Version 2.13 138 a filename that looks unusual; and log entries that raise concern. After detecting an incident, an incident response team performs analysis. This requires some knowledge of normal network operations. The incident should be documented including all the log entries associated with the incident. Containment of the incident is a critical step to stop the damage the incident is causing to your network. Containment activities should be based on previously defined organizational priorities and assessment of risk. Recovery activities restore systems to pre-incident functionality and address its underlying causes. Organizations should use recovery activities as a means of improving their overall resilience to future attacks. Example Your manager asks you to set up your company's incident-response capability [a]. First, you create an email address to collect information on possible incidents. Next, you draft a contact list of all the people who need to know when an incident occurs. You document a procedure for how to submit incidents that includes roles and responsibilities when a potential incident is detected or reported. The procedure also explains how to track incidents, from initial creation to closure [b]. Potential Assessment Considerations Is there an incident response policy which specifically outlines requirements for handling of incidents involving CUI [a]? KEY REFERENCES NIST SP 800-171 Rev. 2 3.6.1

If the contractor intends to flow down CUI to a subcontractor, then the contractor must prepare an SF XXX and distribute it to the subcontractor to ensure the subcontractor properly safeguards CUI. It is estimated 517,392 standard forms may be prepared and distributed by contractors and (printed page 4283) subcontractors each year. On average, it is estimated that it will take the contractor or subcontractor two hours to prepare and distribute the SF XXX. The estimated annual cost to prepare and distribute the SF XXX is \$82,782,270 (517,392 forms * 2 hours/form * \$80), of which \$2,529,440 is attributed to 15,809 small business contractors and subcontractors. d. Train Employees on Handling CUI A contractor shall not permit any contractor employee to collect, develop, receive, transmit, use, handle, or store CUI unless the employee has completed training on properly handling CUI as described in the SF XXX. The contractor must provide evidence of employee training upon request by the contracting officer; however, such requests are expected to be limited to, for example, instances in which the Government is dealing with a CUI incident. It is estimated that approximately 2,191,400 contractor and subcontractor employees may be required to take training on handling CUI, which is expected to take one hour to complete. It is anticipated that agencies will provide their support contractors and personnel with CUI standard training aligned with Federal policy. The estimated annual training cost is \$166,546,400 (2,191,400 employees * 1 hour/employee * \$76/hour), of which \$26,440,400 is attributed to 34,790 small business contractors and subcontractors. The estimated annual recordkeeping cost to maintain contractor training records is \$10,003,741 (2,191,400 records * 0.083 hours/record * \$55/hour), of which \$1,588,164 is attributed to the 34,790 small businesses. The estimated annual reporting cost is \$19,664 (1,430 requests * 0.25 hours/response * \$55/hour), of which \$13,401 is attributed to 975 small businesses. e. Comply With NIST SP 800-172 A limited number of contractors may be required to implement NIST SP 800-172, Enhanced Security Requirements for Protecting Controlled Unclassified Information: A Supplement to NIST Special Publication 800-171, for components of non-Federal systems that process, store, or transmit CUI or that provide security protection for such components when the designated CUI is

associated with a critical program or high-value assets. Contractors that are subject to these enhanced security requirements may incur additional process/information technology configuration, network isolation, and security operations center/threat-related costs; however, the impact on any particular contractor may vary considerably, depending on a contractor's current infrastructure and development environment, and the composition of their customer base.

(5) Upon entrance into military service or civilian employment with the Department of Defense, individuals are asked to provide their SSNs. The SSN becomes the service or employment number for the individual and is used to establish personnel, financial, medical, and other official records.

The notification in paragraph (b)(2) of this section shall be provided the individual when originally soliciting his or her SSN. The notification is not required if an individual is requested to furnish his SSN for identification purposes and the SSN is solely used to verify the SSN that is contained in the records. However, if the SSN is solicited and retained for any purposes other than verifying the existing SSN in the records, the requesting official shall provide the individual the notification required by paragraph (b)(2) of this section. (6) Components shall ensure that the SSN is only collected when there is a demonstrated need for collection. If collection is not essential for the purposes for which the record or records are being maintained, it should not be solicited.

(7) DoD Components shall continually review their use of the SSN to determine whether such use can be eliminated, restricted, or concealed in Component business processes, systems and paper and electronic forms. While use of the SSN may be essential for program integrity and national security when information about an individual is disclosed outside the DoD, it may not be as critical when the information is being used for internal Departmental purposes. (c) Collecting personal information from third parties. When information being solicited is of an objective nature and is not subject to being altered, the information should first be collected from the individual. But it may not be practicable to collect personal information first from the individual in all cases. Some examples of this are: (1) Verification of information through third-party sources for security (printed page 18766) or employment suitability determinations; (2) Seeking third-party opinions such as supervisor comments as to job knowledge, duty performance, or other opinion-type evaluations; (3) When obtaining information first from the individual may impede rather than advance an investigative inquiry into the actions of the individual; and (4) Contacting a third party at the request of the individual to furnish certain information such as exact periods of employment, termination dates, copies of records, or similar information.

(4) Ensure that the Accreditation Body's Board of Directors, professional staff, Information Technology (IT) staff, accreditation staff, and independent assessor staff complete a Tier 3 background investigation resulting in a determination of national security eligibility. This Tier 3 background investigation will not result in a security clearance and is not being executed for the purpose of government employment. The Tier 3 background investigation is initiated using the Standard Form (SF) 86 and submitted by DoD CIO Security to Washington Headquarters Services (WHS) for coordination for processing by the Defense Counterintelligence and Security Agency (DCSA). These positions are designated as non-critical sensitive with a risk designation of 'Moderate Risk' in accordance with title 5 CFR 1400.201(b) and (d) and the investigative requirements of title 5 CFR 731.106(c)(2). (5) Comply with Foreign Ownership, Control or Influence (FOCI) by: (i) Completing the Standard Form (SF) 328 Certificate Pertaining to Foreign Interests and submit it directly to Defense Counterintelligence and Security Agency (DCSA) and undergo a National Security Review with regards to the protection of controlled unclassified information based on the factors identified in 32 CFR 117.11(b) using the procedures outlined in 32 CFR 117.11(c) . The Accreditation Body must receive a non-disqualifying eligibility determination by the CMMC PMO to be recognized by the Department of Defense. (ii) Reporting any change to the information provided on its SF 328 by resubmitting the SF 328 to DCSA within 15 business days of the change being effective. A disqualifying eligibility determination, based on the results of the change, will result in the Accreditation Body losing its authorization or accreditation. (iii) Identifying all prospective C3PAOs to the CMMC PMO. The CMMC PMO will sponsor the prospective C3PAO for a FOCI risk assessment conducted by the DCSA using the SF 328 as part of the authorization and accreditation processes. (iv) Notifying prospective C3PAOs of the CMMC PMO's eligibility determination resulting from the FOCI risk assessment. (6) Obtain a CMMC Level 2 Certification Assessment in accordance with the procedures specified in § 170.17(a)(1) and (c). This assessment, conducted by DCMA DIBCAC, shall meet all requirements for a Level 2 Final Certification Assessment and will not result in a CMMC Level 2 certificate. The CMMC Level 2 assessment process must be performed on a triennial basis. (7) Provide all documentation and records in English. (8) Establish, maintain, and manage an up-to-

date list of authorized and accredited C3PAOs on a single publicly accessible website and provide the list of these entities and their status to the DoD through submission in the CMMC instantiation of eMASS.

CMMC Level 2 certification assessment is the minimum requirement for the subcontractor). In addition, the rule has been revised to make clear that the requirement applies in the performance of a subcontract when the relevant prime contract has a CMMC requirement. The rationale for the minimum level 2 certification flow-down requirement is that the DoD made a risk-based decision not to mandate flow down of the level 3 requirement unless explicit guidance is provided to do so. As stated in § 170.23(a)(3), when a Prime contractor has a requirement of Level 2 certification, any CUI that is flowed down for a subcontractor to process, store, or transmit in performance of the subcontract will also carry a minimum requirement of Level 2 certification assessment. CMMC Program requirements will be identified as solicitation and contract requirements, and contractors will be required to meet the stated CMMC requirements, when applicable, at or above the level identified. One commenter misinterpreted a response to a prior public comment. The quoted content says that contractors and subcontractors each must verify (through CMMC assessment) that all applicable security requirements of NIST SP 800-171 required via DFARS clause 252.204-7012 have been implemented. Contractors are not required to assess subcontractor implementation of the requirements of NIST SP 800-171. The prime contractor's responsibility is to flow down CMMC assessment requirements as described in § 170.23 and also to refrain from disseminating FCI or CUI to subcontractors that have not indicated meeting the CMMC level described in that section for the type of information to be shared. Likewise, subcontractors must also flow down CMMC requirements or refrain from disseminating FCI or CUI. The DoD does not provide SPRS access or other tools for contractors to identify the CMMC status or other companies. The DoD expects that defense contractors will share information about CMMC status with other DIB members to facilitate effective teaming arrangements when bidding for DoD contracts. Prime contractors will not be granted access to subcontractor's information in SPRS. However, prime contractors should communicate early and often with prospective subcontractors to confirm current CMMC status, including whether the level matches that required. This interaction does not involve the government and is beyond the scope of this rule. This rule follows the format and includes all sections required in OMB guidelines for formal rulemaking. The DoD lacks authority to modify the template or omit required sections, which results in some repetition. DIB contractors are responsible for submitting their Level 1 and Level 2 self-assessments and will access SPRS to enter the results. DIB contractors do not have access to CMMC eMASS, as that system is used to support certification assessments only.

From the NIST SP 800-172 Rev 3 Final Public Draft: Defense-in-depth architectural approaches include modularity and layering, the separation of system and user functionality, and security function isolation. The coordination of allocated security requirements is essential to help ensure that an attack that involves one requirement does not create adverse, unintended consequences (e.g., system lockout and cascading alarms) by interfering with other requirements. The value of organizational assets and the impacts or consequences of loss are important considerations in providing additional defensive layers. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY PRA, CRS ADVERSARY E

et seq.). It also fulfills important elements of DoD's critical infrastructure protection responsibilities, as the sector specific agency for the DIB sector see (Presidential Policy Directive 21 (PPD-21), Critical Infrastructure Security and Resilience-). This program allows eligible DIB companies to receive U.S. Government (USG) threat information and to share information about network intrusions that could compromise DoD programs and missions. In addition, the program permits DIB companies and DoD to assess and reduce damage to DoD programs and missions when DoD information is potentially compromised. Furthermore, the information sharing arrangements between the DoD and each participating DIB company that implement the requirements of this are memorialized in a standardized bilateral agreement, known as a Framework Agreement (FA), signed by the participating DIB company and the Government. The rule also provides the eligibility requirements for a company to participate in the DIB CS/IA program. Costs for DIB participants include obtaining access to DoD's secure voice and data transmission systems supporting the DIB CS/IA program and acquiring DoD approved medium assurance certificates. There also are costs associated with the collection requirements for providing point of contact information and cyber incident reporting. Government costs include onboarding new companies and collecting and analyzing cyber incidents from

DIB participants. A foundational element of this bilateral information sharing model is the recognition that the information being shared between the parties includes extremely sensitive nonpublic information, which must be protected against unauthorized uses and disclosures in order to preserve the integrity of the program. For additional information regarding the Government's safeguarding of information received from the DIB companies, with specific focus on PII, see the Privacy Impact Assessment (PIA) for the DIB CS/IA Program (http://dodcio.defense.gov/Portals/0/Documents/DIB%20CS-IA%20PIA_FINAL_signed_30jun2011_VMSS_GGMR_RC.pdf). In addition, this rule and program are intended to be consistent and coordinated with, and updated as necessary to ensure consistency with and support for, other federal activities related to the handling and safeguarding of controlled unclassified information, such as those that are being led by the National Archives and Records Administration pursuant to Executive Order 13556 ·Controlled Unclassified Information· (November 4, 2010) (see <http://www.archives.gov/cui/>). This rule is not intended to implement the new requirements from section 941 of the National Defense Authorization Act for Fiscal Year 2013. Comments DoD published an interim final rule on May 11, 2012 (77 FR 27615). Fifty comments from twelve respondents were received and reviewed by the USG. Comment:

746. ·The Department does not propose to require that the periodic review include a review of whether the conditions of the exception continue to apply because, when the conditions qualifying for an exception change such that an exception no longer applies, a regulated entity would be expected to resume compliance with the standard for encryption and decryption and the associated implementation specifications without exception. Back to Citation 747. ··Defending Against Common Cyber-Attacks,· supra note 396; see also ·HIPAA and Cybersecurity Authentication,· supra note 368. Back to Citation 748. ··Cybersecurity Performance Goals,· supra note 18. Back to Citation 749. Id. Back to Citation 750. · See proposed 45 CFR 164.312(c)(2) . Back to Citation 751. ··What Happened to My Data?: Update on Preventing, Mitigating and Responding to Ransomware,· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Dec. 2019), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-fall-2019/index.html> . Back to Citation 752. · See ·Understanding Anti-Virus Software,· Cybersecurity & Infrastructure Security Agency, U.S. Dept. of Homeland Security (June 30, 2009, rev. Sept. 27, 2019), <https://www.cisa.gov/news-events/news/understanding-anti-virus-software> . Back to Citation 753. ··Improving Detection of Cybersecurity Vulnerabilities and Incidents on Federal Government Systems through Endpoint Detection and Response,· M-22-01, Office of Management and Budget, Executive Office of the President, p. 1 (Oct. 8, 2021), <https://www.whitehouse.gov/wp-content/uploads/2021/10/M-22-01.pdf> . Back to Citation 754. ··Defending Against Common Cyber-Attacks,· supra note 396. Back to Citation 755. Id. Back to Citation 756. Id. Back to Citation 757. Id. Back to Citation 758. · See proposed 45 CFR 164.308(a)(2) . Back to Citation 759. ··What Happened to My Data?: Update on Preventing, Mitigating and Responding to Ransomware,· supra note 751. Back to Citation 760. ··Defending Against Common Cyber-Attacks,· supra note 396. Back to Citation 761. ··Security Standards: Technical Safeguards,· supra note 343, p. 7. Back to Citation 762. Id. Back to Citation 763. ··Cybersecurity Performance Goals,· supra note 18. Back to Citation 764. ·The criterion for auditing actions on health information requires adoption of health IT that has the technical capability to record actions related to electronic health information; restrict the ability for auditing to be disabled to a limited set of users, if the technology permits; detect whether an audit log has been altered; and not allow actions recorded related to electronic health information to be changed, overwritten, or deleted by technology. See 45 CFR 170.315(d)(10) ; see 45 CFR 170.315(d)(2) ; see also 45 CFR 170.210(e) . Back to Citation 765. See, e.g., ·Montefiore Medical Center,· supra note 248. Back to Citation 766. · See proposed 45 CFR 164.308(a)(2) . Back to Citation

The transfer of any personal information from a Privacy Act system of records by any means of communication (such as oral, written, electronic mechanical, or actual review) to any persons, private entity, or government agency, other than the subject of the record, the subject's designated agent or the subject's legal guardian. Within the context of the Privacy Act and this part, this term applies only to personal information that is a part of a Privacy Act system of records. (i) Deceased Individuals. The Privacy Act confers no rights on deceased persons, nor may their next-of-kin exercise any rights for them. However, family members of deceased individuals have their own privacy right in particularly sensitive, graphic, personal details about the circumstances surrounding an individual's death. This information may be withheld when necessary to protect the

privacy interests of surviving family members. Even information that is not particularly sensitive in and of itself may be withheld to protect the privacy interests of surviving family members if disclosure would rekindle grief, anguish, pain, embarrassment, or cause a disruption of their peace minds. Because surviving family members use the deceased's Social Security Number to obtain benefits, DA personnel should continue to protect the SSN of deceased individuals. (j) Individual. A living person who is a citizen of the United States or an alien lawfully admitted for permanent residence. The parent or legal guardian of a minor also may act on behalf of an individual. Members of the United States Armed Forces are individuals. Corporations, partnerships, sole proprietorships, professional groups, businesses, whether incorporated or unincorporated, and other commercial entities are not individuals. (k) Individual Access. The subject of a Privacy Act file or his or her designated agent or legal guardian has access to information about them contained in the Privacy Act file. The term individual generally does not embrace a person acting on behalf of a commercial entity (for example, sole proprietorship or partnership). (l) Denial Authority (formerly Access and Amendment Refusal Authority). The Army Staff agency head or major Army commander designated authority by this part to deny access to, or refuse amendment of, records in his or her assigned area or functional specialization. (m) Maintain. Includes keep, collect, use or disseminate. (n) Members of the Public. Individuals or parties acting in a private capacity. (o) Minor. An individual under 18 years of age, who is not married and who is not a member of the Department of the Army. (p) Official Use. Within the context of this part, this term is used when Department of the Army officials and employees have demonstrated a need for the use of any record or the information contained therein in the performance of their official duties. (q) Personal Information.

(Comment 109) Several comments state that the requirement to record lot/code number or other identifier would cost the industry millions of dollars in operational changes. They state that more warehouse space would be required to separate food by lot number, expensive computer system upgrades would be needed to handle lot code information, and the industry would incur significant administrative and labor costs to enter lot code information into the system. Comments further state that bar code tracing/scanning or radio frequency identification (RFID) systems are costly, and the RFID technology is new. The food distribution business will be affected every minute of every day compared to the infrequent costs associated with investigating food safety issues as the need arises. RFID is being studied and involves placing tagging chips in packaging. It may not be necessary to invent an elaborate system of paper recordkeeping if RFID proves to be useful in the future. (Response) As discussed in response to comment 108 of this document, FDA recognizes the difficulties in tracking lot/code numbers or other identifiers throughout the entire food distribution chain. This final rule accounts for those difficulties. FDA is aware that technology is developing that will enable lot/code number tracking in the future to be cost efficient for all of the food industry. (Comment 110) One comment states that food is not sorted by lot code identification. One pallet/bin, slot, or stockkeeping unit may contain multiple lot numbers. (Response) The final rule does not require warehouse distribution facilities (printed page 71600) to track lot/code number or other identifiers in these final regulations. (Comment 111) A comment states that lot numbers are not scannable or machine readable, and manual transcription of these numbers would introduce errors. The comment states that small businesses would be buried in a mountain of paperwork and this would make it impossible for them to track products accurately. (Response) As explained in response to comment 108, FDA recognizes the difficulties in tracking lot/code numbers or other identifiers. This final rule reflects those considerations. FDA has balanced the need to provide information that would expedite a traceback in a food-related emergency with the ability to record lot numbers. Because food almost always passes through at least one small business in the distribution chain, FDA cannot exempt small businesses entirely from this important requirement. The final rule, however, does give small and very small businesses more time to comply with its requirements. FDA is aware that technology is developing that will enable lot/code number tracking in the future to be cost efficient for all of the food industry.

3.4.2 | The who and w Commands | 34 | | 3. 3.4.2 The who and w Commands The who command, as mentioned previously, displays the list of users currently logged in on the system.

CASE STUDIES IN CYBER SUPPLY CHAIN RISK MANAGEMENT ## Case Studies in Cyber Supply Chain Risk Management Summary of Findings and Recommendations This Summary of Findings and Recommendations summarizes the Case Studies in Cyber Supply Chain Risk Management series' major findings and recommendations based on expert interviews. The Case Studies in Cyber Supply Chain Risk Management

series engaged information security, supply chain, and risk leaders across a diverse set of organizations. These case studies build on the Best Practices in Cyber Supply Chain Risk Management case studies originally published in 2015 with the goals of covering new organizations in new industries and bringing to light current key practices in cyber supply chain risk management. This document describes trends, correlations, or other information garnered from an analysis of the case studies as a whole and may cover information not reported in the individual case studies. This document also contains recommendations for further research, study, and guidance development.

printed page 89068) to any information system associated with the contract efforts that process, store, or transmit FCI or CUI, and to any information system that provides security protections for such systems; or information systems not logically or physically isolated from all such systems. This includes when a 'Test Environment' processes, stores, or transmits FCI or CUI; provides security protections for such systems; or is not logically or physically isolated from such systems. See § 170.19 and the response to public comment under the heading 3. Internet of Things/Operational Technology in the Discussion of Comments and Changes section of this preamble for additional details on defining the scope of CMMC assessments. If GFE cannot be configured to meet all the NIST SP 800-171 Rev 2 requirements or must be maintained in a specified configuration which does not comply with NIST SP 800-171 Rev 2, additional protections such as physical or logical isolation may be used for risk mitigation in accordance with the treatment of Specialized Assets as defined in table 1 to § 170.19(c)(1) CMMC Level 2 Scoping. 5. Fundamental Research Comment: Multiple commenters requested that DoD clarify the application of CMMC requirements to fundamental research. Commenters described adverse consequences of not explicitly exempting fundamental research from the CMMC requirements, noting that institutions of higher education will have to pull out of research agreements with the Department, may no longer accept DoD funds because the resource burden would be cost prohibitive to both the institution and its partners, and the burdens imposed by even CMMC Level 1 requirements would hinder the progress of fundamental research. These commenters also noted that restrictions on posting of public information would inhibit open collaboration and the exchange of ideas that is critical to the advancement of scientific discovery. Commenters also requested that the Department clarify that subcontracts scoped as fundamental research also be exempt from CMMC requirements. Response: CMMC Program requirements are designed to provide increased assurance to the Department that defense contractors can adequately protect FCI and CUI, in accordance with already applicable regulations and standards. Fundamental research is defined by National Security Defense Directive (NSDD)-189 [17]

Amend section 39.201 by removing from paragraph (a) 'information and communication technology' and adding 'information and communications technology' in its place. 18. Add a new subpart 39.X to read as follows: (printed page 68415) Subpart 39.X Federal Information Systems 39.X00 Scope of subpart. This subpart provides policies and procedures for acquiring services to develop, implement, operate, or maintain a Federal information system (FIS) (E.O. 14028 , Improving the Nation's Cybersecurity, dated May 12, 2021). This subpart does not apply to National security systems (see 39.002). 39.X01 Definitions. As used in this subpart: Administrative account means a user account with full privileges (i.e., with full function and access rights) intended to be used only when performing management tasks, such as installing updates and application software, managing user accounts, and modifying operating system and application settings. Authorization boundary means all components of an information system to be authorized for operation by an authorizing official. This excludes separately authorized systems to which the information system is connected (OMB Circular No. A-130). Authorizing official means a senior Federal official or executive with the authority to authorize (i.e., assume responsibility for) the operation of an information system or the use of a designated set of common controls at an acceptable level of risk to agency operations (including mission, functions, image, or reputation), agency assets, individuals, other organizations, and the Nation (OMB Circular No. A-130). Cloud computing means a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. Cloud computing is characterized by on-demand self-service, broad network access, resource pooling, rapid elasticity, and measured service; and includes service models such as software-as-a-service, infrastructure-as-a-service, and platform-as-a-service (NIST SP 800-145). Component means a discrete identifiable information and operational technology asset that represents a building block of a system and may include hardware, software, and firmware. Cyber supply chain risk means the potential for harm or compromise that arises as a result of cybersecurity risks from suppliers,

their supply chains, and their products or services. This includes risks that arise from threats exploiting vulnerabilities or exposures within products and services traversing the supply chain as well as threats or exposures within the supply chain itself. The level of risk depends on the likelihood that relevant threats may exploit applicable vulnerabilities and the consequential potential impacts (NIST SP 800-161 and 800-203). Government-related data

direct agencies to assess all costs, benefits, and available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health, safety effects, distributive impacts, and equity). Executive Order 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This proposed rule has been designated significant, under Executive Order 12866. B. Congressional Review Act (5 U.S.C. 801 et seq.) Pursuant to the Congressional Review Act, this proposed rule has not been designated a major rule, as defined by 5 U.S.C. 804(2). This proposed rule will not have an economic effect above the \$100 million threshold defined in 5 U.S.C. 804(2) or spur a major increase in costs or prices for consumers, individual industries, Federal, State, or local government agencies, or geographic regions; or have significant adverse effects on competition, employment, investment, productivity, innovation, or on the ability of United States-based enterprises to compete with foreign-based enterprises in domestic and export markets. C. Public Law 96-354, Regulatory Flexibility Act (5 U.S.C. 601) The Office of the DoD Chief Information Officer certifies that this proposed rule is not subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would not, if promulgated, have a significant economic impact on a substantial number of small entities. This proposed rule will have a significant positive impact on small entities that will become eligible to participate in and receive benefits through the DIB CS Program. For DIB participants, this program provides cyber threat information and technical assistance through analyst-to-analyst exchanges, mitigation and remediation strategies, and cybersecurity best practices in a collaborative environment. The shared threat information is used to bolster a company's cybersecurity posture and mitigate the growing cyber threat. The program's tailored support for small, mid-size, and large companies with varying cybersecurity maturity levels is an asset for participants.

(i) Notify appropriate parties of action taken under paragraphs (a) through (d) of this section and the basis for such action only to the extent necessary to effectuate the action; * * * * 16. Revise section 239.7306 to read as follows: 239.7306 Solicitation provision and contract clause. (a) Insert the provision at 252.239-7017, Notice of Supply Chain Risk, in solicitations, including solicitations using FAR part 12 procedures for the acquisition of commercial items, for information technology, whether acquired as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as defined at 239.7301. (b) Insert the clause at 252.239-7018, Supply Chain Risk, in solicitations and contracts, including solicitations and contracts using FAR part 12 procedures for the acquisition of commercial items, for information technology, whether acquired as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as defined at 239.7301. PART 244-SUBCONTRACTING POLICIES AND PROCEDURES 17. Revise section 244.201-1 to read as follows: 244.201-1 Consent requirements. In solicitations and contracts for information technology, whether acquired as a service or as a supply, that is a covered system or covered item of supply as those terms are defined at 239.7301, consider the need for a consent to subcontract requirement regarding supply chain risk (see subpart 239.73). For additional guidance see PGI 244.201-1. PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 252.239-7018 [Amended] 18. Amend section 252.239-7018 by: a. Removing the clause date (NOV 2013) and adding (OCT 2015) in its place; b. Amending paragraph (b) by removing shall maintain controls and adding shall mitigate supply chain risk in its place, and removing the phrase to minimize supply chain risk before the period; and c. Removing paragraph (e). [FR Doc. 2015-27463 Filed 10-29-15; 8:45 am] BILLING CODE 5001-06-P

ronments than in enterprise environments, additional security controls are recommended, such as encrypting sensitive data stored on the devices, and existing security controls may need to be adjusted. For example, if a personal firewall on a telework client device has a single policy for all environments, then it is likely to be too restrictive in some situations and not restrictive enough in others. Whenever possible, organizations should use personal firewalls capable of supporting multiple policies for their telework client devices and configure the firewalls properly for the enterprise environment and an external environment, at a minimum.

emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is a significant regulatory action and, therefore, was subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804. VI. Executive Order 13771 This rule is expected to be an E.O. 13771, Reducing Regulation and Controlling Regulatory Costs, deregulatory action. The total annualized value of the cost savings is \$1,521,836. Details on the estimated cost savings can be found in section IV. of this preamble. VII. Regulatory Flexibility Act DoD expects that this proposed rule may have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601 et seq. Therefore, an initial regulatory flexibility analysis has been prepared and is summarized as follows: This rule proposes to implement section 831 the National Defense Authorization Act (NDAA) for Fiscal Year (FY) 2017, which amends 10 U.S.C. 2307 to address the use of performance-based payments. The primary objective of this rule is to remove the restrictions at DFARS 232.1001(a) and the clauses at 252.232-7012(b)(i) and 252.232-7013(b)(i) that limit performance-based payments to amounts not greater than costs incurred up to the time of payment, as required 10 U.S.C. 2307. This rule will apply to approximately 50 small entities per year that submit offers and are awarded contracts that provide performance-based contract payments from DoD, as well as an additional 5 offerors that submit offers in response to solicitations that may result in contracts that provide performance-based payments but do not receive an award. (printed page 18223) This rule adds a reporting requirement that will require an entry in the annual representations and certifications with regard to whether the output of the offeror's accounting system is in compliance with Generally Accepted Accounting Principles, as evidenced by audited financial statements. DoD estimates that the skill necessary for this requirement is at the journeyman level and that each entry will require an average of 6 minutes. The rule does not duplicate, overlap, or conflict with any other Federal rules. This rule will not have a significant economic impact on small entities. The burden imposed by the new representation is minimal. The net impact is likely to benefit small entities, to the extent that the entity may receive an increase in cash flow if the negotiated value of performance-based payment events exceeds the actual costs incurred at the time of event completion. There are no significant alternatives consistent with the stated objectives of the statute. DoD invites comments from small business concerns and other interested parties on the expected impact of this rule on small entities.

This proposed rule does not duplicate, overlap, or conflict with any other Federal rules. This proposed rule implements the requirements of 32 CFR part 2002 to ensure uniform implementation of Federal contractor requirements for managing CUI. While this rule is modeled after DFARS clause 252.204-7012, it does not conflict with the existing clause. It is expected that the DFARS clause will be amended in the future to address DoD-specific requirements that may be in addition to the FAR clause. DoD, GSA, and NASA were unable to identify any alternatives that would reduce the burden on small entities and still meet the objectives of 32 CFR part 2002. It is not possible to establish different compliance standards that take into account the resources available to small entities or exempt small entities from the rule, or any part thereof, that does not increase the risk of CUI incidents. However, by implementing a more standardized set of requirements for contractor information systems and for CUI safeguarding across agencies, small businesses that engage in contracts involving sensitive Government information might find it easier and less costly to meet security requirements for such information under this rule, because the variation of system configurations and requirements will be significantly reduced. This, in turn, may make such businesses more competitive for future Government contracts. The Regulatory Secretariat Division has submitted a copy of the IRFA to the Chief Counsel for Advocacy of the Small Business Administration. A copy of the IRFA may be obtained from the Regulatory Secretariat Division. DoD, GSA, and NASA invite comments from small business concerns and other interested parties on the expected impact of this proposed rule on small entities. DoD, GSA, and NASA will also consider comments from small entities concerning the existing regulations in subparts affected by the rule in accordance with 5 U.S.C. 610. Interested parties must submit such comments separately and should cite 5 U.S.C. 610 (FAR Case 2017-016), in correspondence. VIII. Paperwork Reduction Act The Paperwork Reduction Act (44 U.S.C. 3501-3521) applies because the proposed rule contains information collection requirements. Accordingly, the Regulatory Secretariat Division has submitted a request for approval of a new information collection requirement concerning controlled unclassified information to the Office of Management and Budget. A. Public Burden for This Collection of Information 1. System Security Plan. Public reporting burden for this collection of

information is estimated to average 0.50 hour per response including the time to prepare and submit the plan. The annual reporting burden is estimated as follows: Respondents: 1,430. Total annual responses: 1,430. Total burden hours: 715. This estimate is based on approximately one response per respondent. The annual recordkeeping burden is estimated as follows: Recordkeepers: 10,242. Total annual records: 10,242.

the ratio of the number for code 488510 to the total number for code 488 in the County Business Pattern data, and then applied that ratio to the number of establishments under code 488 in the NES data. We assumed a uniform distribution of food and nonfood carriers under the general freight trucking category and estimated the number of establishments that transport food products under code 4841 to be half of the total for that category. We assumed the number of establishments under code 488510 that arrange freight transportation for food products to be 20 percent of the total for that category. We assumed that the same percentage applies to the total assumed for specialized freight carriers dedicated to the food industry. As a result of these changes, the total number of domestic transportation and packing facilities is revised upward from 16,773 facilities used in the PRIA to 234,980. The numbers of establishments by code are reported in table 12 of this document. Table 12. Number of Transportation Establishments by NAICS Code

NAICS Code	Description	CBP 2000	NES 99
481112	Scheduled freight air transportation	584	2,413
481212	Nonscheduled chartered freight air transportation	217	483111
483111	Deep sea freight transportation	485	4,754
483113	Coastal and Great Lakes freight transportation	546	483211
483211	Inland water freight transportation	402	4841
4841	General freight trucking	27,937	164,242
48422	Specialized freight (exclusively used) trucking, local	6,499	4,946
48423	Specialized freight (exclusively used) trucking, long distance	2,580	8,189
488320	Marine cargo handling	607	2,415
488510	Freight transportation arrangement	3,035	3,814
488991	Packing and crating	1,315	

Foreign transportation carriers that cross the northern and southern U.S. borders are not counted in the County Business Pattern and NES data, because they are foreign based. All of these carriers are subject to DOT regulations, and the costs of compliance for these facilities are assumed to be zero because the final rule allows a transporter to meet its obligations by keeping the records currently required by DOT. However, foreign transportation carriers that cross the northern and southern U.S. borders are assumed to incur learning costs associated with this final rule.

Several other comments state that, because their ingredients are commingled, they are unable to provide FDA with information that ties the specific source of each ingredient to a lot of the finished product. Certain bulk products such as flour, shortening, vegetable oil, fructose syrup, and milk cannot be identified as ingredient lots. Other comments state that the ability to identify specific sources of ingredients will vary based on many factors. One comment states that produce is often commingled to meet marketplace needs. A few comments state that some processors commingle ingredients in their processing operations, which makes it impossible to trace the specific source of ingredients to a lot of finished product. One comment states that most companies would only be able to produce possible sources of ingredients in batches of final products. The comment asserts that companies should only be required to do so in a crisis. (Response) FDA acknowledges that certain business practices are not amenable to linking incoming ingredients with outgoing product and that it may not always be possible to identify the specific source of an ingredient that was used to make a lot of finished product. It is not FDA's intent to mandate reengineering of long-standing existing processes. For this reason, the final rule requires the identification of the specific source of each ingredient that was used to make every lot of finished product only when the food is released and only if this information is reasonably available. With respect to the comment that companies should only be required to produce records during a crisis, the agency notes that FDA will request access to the records under section 306 of the Bioterrorism Act only when it has reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals. (Comment 95) One comment requests that the agency accept testing of each delivery of incoming product as a substitute for the requirement to tie the specific source of each ingredient to a lot of the finished product. The comment asserts that this testing provides the needed safeguards and would ensure that the ingredient is not contaminated chemically, physically, or biologically.

(13) Implement a quality assurance function that ensures the accuracy and completeness of assessment data prior to upload into the CMMC instantiation of eMASS. Any individual fulfilling the quality assurance function must be a CCA and cannot be a member of an Assessment Team for which they are performing a quality assurance role. A quality assurance individual shall manage the C3PAO's quality

assurance reviews as defined in paragraph (b)(14) of this section and the appeals process as required by paragraphs (b)(19) and (20) of this section and in accordance with ISO/IEC 17020:2012(E) (incorporated by reference, see § 170.2) and ISO/IEC 17011:2017(E) (incorporated by reference, see § 170.2). (14) Conduct quality assurance reviews for each assessment, including observations of the Assessment Team's conduct and management of CMMC assessment processes. (15) Ensure that all Level 2 certification assessment activities are performed on the information system within the CMMC Assessment Scope. (16) Maintain all facilities, personnel, and equipment involved in CMMC activities that are in scope of their Level 2 certification assessment and comply with all security requirements and procedures as prescribed by the Accreditation Body. (17) Ensure that all assessment data and information uploaded into the CMMC instantiation of eMASS assessment data is compliant with the CMMC assessment data standard as set forth in eMASS CMMC Assessment Import Templates on the CMMC eMASS website: <https://cmmc.emass.apps.mil>. This system is accessible only to authorized users. (18) Issue Certificates of CMMC Status to OSCs in accordance with the Level 2 certification assessment requirements set forth in § 170.17, that include, at a minimum, all industry CAGE codes associated with the information systems addressed by the CMMC Assessment Scope, the C3PAO name, assessment unique identifier, the OSC name, and the CMMC Status date and level. (19) Address all OSC appeals arising from Level 2 certification assessment activities. If the OSC or C3PAO is not satisfied with the result of the appeal either the OSC or the C3PAO can elevate the matter to the Accreditation Body for final determination. (20) Submit assessment appeals, review records, and decision results of assessment appeals to DoD using the CMMC instantiation of eMASS.

§ 170.10 CMMC Assessor and Instructor Certification Organization (CAICO). (a) Roles and responsibilities. The CAICO is responsible for training, testing, authorizing, certifying, and recertifying CMMC assessors, instructors, and related professionals. Only the CAICO may make decisions relating to examination certifications, including the granting, maintaining, recertifying, expanding, and reducing the scope of certification, and suspending or withdrawing certification in accordance with current ISO/IEC 17024:2012(E) (incorporated by reference, see § 170.2). At any given point in time, there will be only one CAICO for the DoD CMMC Program. (b) Requirements. The CAICO shall:

DoD agrees that appropriate use of PBPs has benefits. This rule is consistent with the statutory preference for PBP; however, the Government reserves the right to determine the best option for contract financing based on the individual contract action. Due to the evaluation criteria required to determine whether PBP is the best method of contract financing, DoD will not direct that PBP is the default choice for contracts.

b. Eliminate the requirement for two-step negotiation and consideration. Comment: Although not addressed in the proposed rule, many respondents were concerned that the existing procedures at DFARS 232.1004 pose hindrances to the preference for PBPs. Specifically, many respondents were concerned about retention of the procedures at DFARS 232.1004, which require initial agreement on price using customary progress payments before negotiations begin on the usage of performance-based payments. One respondent stated that the two-step negotiation process is unjustifiably unique to DoD. Furthermore, the DFARS currently requires negotiation of consideration to be received by the Government if the performance-based payments payment schedule will be more favorable to the contractor than customary progress payments. Two respondents stated that this process is counter to the system outlined in FAR 32.005(a). One of these respondents stated that performance-based payments are a program management tool, whereas progress payments simply reimburse contractors for costs incurred. Therefore, according to the respondent, comparing the payments schedule of one to the other is not an apples-to-apples comparison. Performance goals required by PBPs serve as additional requirements placed on the contractor that offset the payment schedule difference offered by PBPs compared to progress payments. Requiring additional consideration erodes the potential benefits of PBPs relative to the increased risk accepted by contractors, and undermines the policy objective to incentivize performance. Several respondents stated that DoD added this policy specifically to reverse the preference for PBPs. Response: DoD has removed this requirement in the final rule (see DFARS 232.1004).

c. Eliminate or completely overhaul the PBP analysis tool. Comment: Several respondents specifically recommended eliminating or completely overhauling the PBP analysis tool, which DoD developed to allow the contracting officer and industry to compare the financial cost and benefits of using PBPs versus customary progress payments. While one respondent acknowledged that slight changes have been made to improve the tool, the respondent still finds the conceptual shortcomings of DoD's policy unchanged. One respondent offered the following detailed criticisms of the PBP Tool:

confidentiality, integrity, and availability) and privacy of Government data; or for the purpose of

audits, investigations, inspections, or other similar activities, as authorized by law, regulation, or this contract, the Contractor shall provide the Government's authorized representatives (authorized representatives include CISA, except for contracts with the Department of Defense, the Intelligence Community, or for National Security Systems, and could include other Federal agencies, as specified by the Contracting Officer) with:

- (A) Timely access, including full access, to all Government data and Government-related data;
- (B) Timely access to contractor personnel involved in performance of the contract; and
- (C) Specifically for the purpose of audit, investigation, inspection, or other similar activity, as authorized by law, regulation, or this contract, timely physical access to any Contractor facility with Government data.

(ii) In response to a request for access from CISA, the Contractor shall:

- (A) First confirm the validity of the request by contacting CISA Central by email at report@cisa.gov, or by telephone at 888-282-0870; and
- (B) Immediately notify the Contracting Officer and any other agency official designated in the contract, in writing, of receipt of the request. Provision of information and access to CISA under this clause shall not be delayed by submission of this notification or awaiting acknowledgement of its receipt.

(g) Notification of third-party access requests. The Contractor shall notify the Contracting Officer promptly of any requests from a third-party for access to Government data or Government-related data, including any warrants, seizures, or subpoenas it receives, including those from another Federal, State, or local agency. The Contractor shall comply with applicable clauses, regulations, and laws concerning protection of Government data and Government-related data from any unauthorized disclosure.

(h) Indemnity for potential or actual loss or damage of Government data.

(1) The Contractor shall indemnify the Government and its officers, agents, and employees acting for the Government against any liability arising out of the performance of this contract, including costs and expenses, incurred as the result of the Contractor's unauthorized introduction of copyrighted material to which the Contractor has no rights or license that may infringe on the copyright interest of others, information subject to a right of privacy, and any libelous or other unlawful matter into Government data. The Contractor agrees to waive any and all defenses that may be asserted for its benefit, including (without limitation) the Government Contractors Defense.

(2) The Contractor shall indemnify the Government and its officers, agents, and employees acting for the Government against (printed page 68419)

(E) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6), if the disclosure would compromise the objectivity or fairness of the test or examination process.

(F) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7), but only to the extent that the disclosure of such material would reveal the identity of a confidential source.

(G) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(1), (k)(2), (k)(3), (k)(5), (k)(6), or (k)(7) from subsections 5 U.S.C. 552a(c)(3) and (d).

(ii) Reasons.

(A) Personnel investigations may obtain from another Federal agency, properly classified information which pertains to national defense and foreign policy. Application of exemption (k)(1) may be necessary to preclude the data subject's access to an amendment of such classified information under 5 U.S.C. 552a(d) in order to protect such information.

(B) Personnel investigations may contain investigatory material compiled for law enforcement purposes other than material within the scope of 5 U.S.C. 552a(j)(2), e.g. investigations into the administration of the merit system. Application of exemption (k)(2) may be necessary to preclude the data subject's access to or amendment of such records, under 552a(c)(3) and (d) because otherwise, it would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement.

(C) Personnel investigations may obtain from another Federal agency, information that relates to providing protective services to the President of the United States or other individuals pursuant to section 3056 of title 18. Application of exemption (k)(3) may be necessary to preclude the data subject's access to or amendment of such records (printed page 14763) under 5 U.S.C. 552a(d) to ensure protective services provided to the President and others are not compromised.

(D) All information about individuals in these records that meets the criteria stated in 5 U.S.C. 552a(k)(5) is exempt from the requirements of 5 U.S.C. 552a(c)(3) and (d) in order to protect the identity of confidential sources incident to determinations of suitability, eligibility, or qualifications for Federal employment, military service, contract, and security clearance determinations.

(E) All material and information in the records that meets the criteria stated in 5 U.S.C. 552a(k)(6) is exempt from the requirements of 5 U.S.C. 552a(d), relating to access to and amendment of records by the data subject in order to preserve the confidentiality and integrity

of Federal testing materials. (F) All material and information in the records that meets the criteria stated in 5 U.S.C. 552a(k)(7)

(B) From subsections (d) and (f) because providing access to investigative records and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because this system of records is compiled for investigative purposes and is exempt from the access provisions of subsections (d) and (f). (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NRO will, nevertheless, continue to publish such a notice in broad generic terms as is its current practice. (F) Consistent with the legislative purpose of the Privacy Act of 1974, the NRO will grant access to nonexempt material in the records being maintained. Disclosure will be governed by NRO's Privacy Regulation, but will be limited to the extent that the identity of confidential sources will not be compromised; subjects of an investigation of an actual or potential criminal or civil violation will not be alerted to the investigation; the physical safety of witnesses, informants and law enforcement personnel will not be endangered, the privacy of third parties will not be violated; and that the disclosure would not otherwise impede effective law enforcement. Whenever possible, information of the above nature will be deleted from the requested documents and the balance made available. The controlling principle behind this limited access is to allow disclosures except those indicated above. The decisions to release information from these systems will be made on a case-by-case basis. (4) System identifier and name. QNRO-15, Facility Security Files. (i) Exemption.

(3) System identifier and name. S500.20 (Specific exemption), Defense Logistics Agency (DLA) Criminal Incident Reporting System (DCIRS). (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). If an individual, however, is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information except to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(3)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) The specific sections of 5 U.S.C. 552a from which the system is to be exempted are 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (H), (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2). (iii) Reasons. (A) From subsection (c)(3), as to grant access to an accounting of disclosures as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation or prosecutive interest by DLA or other agencies. This could seriously compromise case preparation by: Prematurely revealing its existence and nature; compromising or interfering with witnesses or making witnesses reluctant to cooperate; and leading to suppression, alteration, or destruction of evidence. (B) From 5 U.S.C. 552a(d) and (f), as providing access to this information could result in the concealment, destruction or fabrication of evidence and jeopardize the safety and wellbeing of informants, witnesses and their families, and law enforcement personnel and their families. Disclosure of this information also could reveal and render ineffectual investigative techniques, sources, and methods used by this component and could result in the invasion of privacy of individuals only incidentally related to an investigation. Investigatory material is exempt to the extent that the disclosure of such material would reveal the identity of a source who furnished the information to the Government under an express promise that

the identity of the source would be held in confidence, or prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. This exemption will protect the identities of certain sources that would be otherwise unwilling to provide information to the Government. The exemption of the individual's right of access to his/her records and the reasons therefore necessitate the exemptions of this system of records from the requirements of the other cited provisions. (C) From 5 U.S.C. 552a(e)(1)

Additionally, as discussed above, several organizations have published and maintained compilations of voluntary standards, guidelines, best practices, methodologies, procedures, and processes for protecting the security of sensitive and confidential information, including PHI. These compilations and the State regulations discussed above range from granular [161] to high-level [162] and from health care-specific [163] to industry agnostic. [164] Despite these differences, these compilations and regulations have a great deal in common with each other and with the Security Rule, its longevity notwithstanding. In fact, the foundational elements of the Security Rule, promulgated more than 20 years ago, can still be found in cybersecurity compilations published today. They generally either require or recommend administrative, physical, and technical safeguards to identify and mitigate risks and vulnerabilities, implement authentication and access controls, conduct security awareness and training for information system users, and plan for contingencies and incident response. [165] Additionally, these compilations all require or recommend the designation of a specific individual who is accountable for implementing the requirements or recommendations. And, importantly, they all ultimately address how to maintain the (printed page 910) confidentiality, integrity, and availability of sensitive and confidential information, including ePHI. A major distinguishing factor between the content of the Security Rule and these compilations and regulations is the Security Rule's scope. The compilations and regulations are designed to protect various types of data and information systems broadly. In comparison, a defining quality of the Security Rule's requirements is that they focus specifically on the protection of ePHI and the information systems that create, receive, maintain, or transmit ePHI. Thus, while the foundational elements of various cybersecurity compilations and State regulations and the Security Rule may be the same, the Security Rule alone addresses the application of those elements to ePHI and all of the components of information systems that create, receive, maintain, or transmit ePHI. Thus, while the standards of the Security Rule generally align with those of other cybersecurity standards, frameworks, best practices, guidelines, processes, and procedures, the specific implementation specifications of the Security Rule reflect the particular sensitivities of the health care industry, particularly small and rural health care providers, in a way that is necessary to ultimately improve the efficiency and effectiveness of the health care system and avoid imposing unreasonable compliance burdens on regulated entities. B. The Health Care Environment Has Changed Since the Security Rule Was Last Revised and Will Continue To Evolve

(i) DoD personnel and system managers shall conduct themselves consistent with established rules of conduct 310.8 so that personal information to be stored in a system of records only shall be collected, maintained, used, and disseminated as is authorized by this part, 5 U.S.C. 552a and DoD 5400.11-R. (j) DoD personnel, including but not limited to family members, retirees, contractor employees, and volunteers, shall be notified, in a timely manner, consistent with the requirements of DoD 5400.11-R, if their personal information, whether or not included in a system of records, is lost, stolen, or compromised. (k) DoD Field Activities shall receive Privacy Program support from the Director, Washington Headquarters Services. §310.6 Responsibilities. (a) The Director of Administration and Management, Office of the Secretary of Defense, shall: (1) Serve as the Senior Privacy Official for the Department of Defense. (2) Provide policy guidance for, and coordinate and oversee administration of, the DoD Privacy Program to ensure compliance with policies and procedures in 5 U.S.C. 552a and OMB Circular A-130. (3) Publish DoD 5400.11-R and other guidance, including Defense Privacy Board Advisory Opinions, to ensure timely and uniform implementation of the DoD Privacy Program. (4) Serve as the Chair to the Defense Privacy Board and the Defense Data Integrity Board (see §310.9). (5) Supervise and oversee the activities of the Defense Privacy Office (see §310.9). (b) The Director, WHS, under the DA&M, shall provide Privacy Program support for DoD Field Activities. (c) The General Counsel of the Department of Defense shall: (1) Provide advice and assistance on all legal matters arising out of, or incident to, the administration of the DoD Privacy Program. (2) Review and be the final approval authority on all advisory opinions issued by the Defense Privacy Board or the Defense Privacy Board Legal Committee. (3) Serve as a member of the Defense Privacy Board, the Defense Data Integrity Board, and the Defense Privacy Board Legal Committee (310.9). (d) The Secretaries of the Military Departments and the Heads of the Other DoD

Components, except as noted in § 310.5(k), shall: (1) Provide adequate funding and personnel to establish and support an effective DoD Privacy Program, to include the appointment of a senior official to serve as the principal point of contact (POC) for DoD Privacy Program matters. (2) Establish procedures, as well as rules of conduct, necessary to implement this part and DoD 5400.11-R to ensure compliance with the requirements of 5 U.S.C. 552a and OMB Circular A-130. (3) Conduct training, consistent with the requirements of DoD 5400.11-R, on the provisions of this part, 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R, for assigned, employed and detailed, to include contractor, personnel and individuals having primary responsibility for implementing the DoD Privacy Program.

for regulated entities to revise business associate agreements to comply with the proposed changes to the requirements of the Security Rule. The proposed transition period would allow regulated entities to revise existing agreements by the earlier of the contract renewal date that falls after the compliance date of a final rule, or within one year of the rule's effective date. For a large share of existing agreements, this would allow regulated entities to complete the revisions on a rolling basis according to the dates they are renewed. The Department estimates that 1,822,600 [964] business associate agreements would need to be revised if this NPRM is adopted and that, on average, the portion of this activity that results from the rule's modifications would take an hour of a lawyer's time for each regulated entity. This would result in annual costs of \$309,258,768 [= 1,822,600 regulated entities × 1 hour × \$169.68]. The Department recognizes that this estimate may not fully account for all revised business associate agreements. However, the Department believes that in some instances, one hour of time is more than would be needed. We also believe it is likely that, for some regulated entities, a professional other than a lawyer would be responsible for the revised agreements at a lower hourly wage. For some large business associates, the Department believes that a single agreement is used for most of its customers. The Department's estimates assume that most agreements would be revised within the first year and accounts for all of them within that time period. This would be considered a one-time cost; in other words, it is not carried over into future years. As with all the estimates in this NPRM, the Department invites comments about the assumptions underlying the proposed cost projections.

n. Plan Sponsors' Obligations

Proposed 45 CFR 164.314(b)(2) would mandate that group health plan documents require their health plan sponsors who receive ePHI that is not limited to summary health information or enrollment or disenrollment information to deploy the administrative, physical, and technical safeguards for ePHI required by the Security Rule and notify their group health plans upon activation of the plan sponsors' contingency plan. Currently, plan documents must require such health plan sponsors to have safeguards in place, but not necessarily the safeguards specified in the Security Rule. [965] The Department estimates that an additional 52.42 hours of labor would be needed for each affected health plan sponsor to bring its security safeguards for ePHI into compliance with the Security Rule standards and to notify group health plans when its contingency plan is activated, over and above the actions attributable to safeguards already in place for ePHI and for sponsors' electronic information systems generally. The Security Rule compliance activities attributed to group health plan sponsors are shown in table 7, below.

As discussed above, the Department believes that a group health plan needs to be notified in a timely manner when a plan sponsor activates its contingency plan because of the potential implications on the ability of a group health plan to protect the confidentiality, integrity, and availability of ePHI in its relevant electronic information systems. Accordingly, we believe that 24 hours would provide a plan sponsor sufficient time to do all of the following: determine that there is an emergency or other occurrence adversely affecting the plan sponsor's relevant electronic information systems; determine that it needs to activate its contingency plan; activate its contingency plan; identify any group health plans that need to be notified; and notify such group health plans. Similarly, as discussed above, we propose to permit the group health plan and plan sponsor to negotiate the form, content, or manner of the notice and include them in their plan documents if they so choose. The Department believes that requiring a plan sponsor to provide prompt notice to the group health plan when the plan sponsor activates its contingency plan would enable group health plans and plan sponsors to maintain individuals' confidence in their commitment to protecting the confidentiality, integrity, and availability of ePHI. Additionally, consistent with our proposal to revise 45 CFR 164.306, the Department proposes to remove the term "required" from the implementation specification at 45 CFR 164.314(b)(2) consistent with our overall proposal to eliminate the distinction between "required" and "addressable" implementation specifications. However, a regulated entity would still be required to comply with all standards and implementation

specifications as applicable to its situation, as proposed in 45 CFR 164.306(c) . 3. Request for Comment The Department requests comment on the foregoing proposals, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular: a. How group health plans currently ensure that plan sponsors implement reasonable and appropriate administrative, physical, and technical safeguards to protect the confidentiality, integrity, and availability of ePHI. b. Whether it is appropriate for group health plans to require plan sponsors to implement the administrative, physical, and technical safeguards of the Security Rule. If not, please explain and provide alternatives for how the Department should ensure the confidentiality, integrity, and availability of ePHI when it is disclosed to plan sponsors. c. Whether business associates currently notify covered entities (or subcontractors notify business associates) upon activation of their contingency plans, and if so, the manner and timing of such notice. d. Whether plan sponsors currently notify group health plans upon activation of their contingency plans, and if so, the manner and timing of such notice.

enforcement purposes it is impossible to determine in advance what information is accurate, relevant, timely, and complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light and the accuracy of such information can only be determined in a court of law. The restrictions of subsection (e)(5) would restrict the ability of trained investigators and intelligence analysts to exercise their judgment reporting on investigations and impede the development of intelligence necessary for effective law enforcement. (J) From subsection (e)(8) because the individual notice requirements of subsection (e)(8) could present a serious impediment to law enforcement as this could interfere with the ability to issue search authorizations and could reveal investigative techniques and procedures. (K) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (L) From subsection (g) because portions of this system of records are compiled for law enforcement purposes and have been exempted from the access provisions of subsections (d) and (f). (9) System identifier and name. A0190-9 OPMG, Absentee Case Files. (i) Exemption. Parts of this system of records may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principal function any activity pertaining to the enforcement of criminal laws. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(j) (2) from subsections 5 U.S.C. 552a(c)(3) , (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (e)(4)(H), (e)(4)(I), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (c)(4) because an exemption is being claimed for subsection (d), making this subsection not applicable. (C) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement.

h communications that describes the manufacturer's third party, contractor, and vendor IoT device security oversight, and for including security and privacy requirements within contractual agreements. Information that may be necessary to provide to explain supply chain risk management include details and actions such as: - a. Communications, detailed descriptions, methods, techniques, and/or policies the manufacturer uses to monitor IoT device activities and associated systems security control compliance by external service providers on an ongoing basis. - b. Providing detailed information describing how the IoT device manufacturer performs oversight activities for their supporting entities, including such information as: - How the manufacturer meets legal and/or regulatory safeguard requirements related to supply chain risk management. - Details about the activities performed by each of the supporting entities to whom the manufacturer outsources IoT device support activities, and how such activities are monitored.

CM.L2-3.4.5 · Access Restrictions for Change CMMC Assessment Guide · Level 2 | Version 2.13 100
 CM.L2-3.4.5 · ACCESS RESTRICTIONS FOR CHANGE Define, document, approve, and enforce physical and logical access restrictions associated with changes to organizational systems. ASSESSMENT OBJECTIVES [NIST SP 800-171A]88 Determine if: [a] physical access restrictions associated with changes to the system are defined; [b] physical access restrictions associated with changes to the system are documented; [c] physical access restrictions associated with changes to the system are

approved; [d] physical access restrictions associated with changes to the system are enforced; [e] logical access restrictions associated with changes to the system are defined; [f] logical access restrictions associated with changes to the system are documented; [g] logical access restrictions associated with changes to the system are approved; and [h] logical access restrictions associated with changes to the system are enforced. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]88 Examine [SELECT FROM: Configuration management policy; procedures addressing access restrictions for changes to the system; system security plan; configuration management plan; system design documentation; system architecture and configuration documentation; system configuration settings and associated documentation; logical access approvals; physical access approvals; access credentials; change control records; system audit logs and records; other relevant documents or records]. Interview [SELECT FROM: Personnel with logical access control responsibilities; personnel with physical access control responsibilities; personnel with information security responsibilities; system or network administrators]. Test [SELECT FROM: Organizational processes for managing access restrictions associated with changes to the system; mechanisms supporting, implementing, and enforcing access restrictions associated with changes to the system]. 88 NIST SP 800-171A, p. 28.

Vulnerabilities discovered, for example, via the scanning conducted in response to RA.L2 - 3.11.2, are remediated with consideration of the related assessment of risk. The consideration of risk influences the prioritization of remediation efforts and the level of effort to be expended in the remediation for specific vulnerabilities. FURTHER DISCUSSION Not all vulnerabilities captured in a vulnerability scanner may pose the same level of risk to an organization. Prioritize mitigation efforts to close the most critical vulnerabilities first. 176 NIST SP 800-171A, p. 50. 177 NIST SP 800-171 Rev. 2, p. 34.

(D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (2) System identifier and name. A0 025-400-2 OAA, Army Records Information Management System (ARIMS). (i) Exemption. During the course of records management, declassification and claims research, exempt materials from other systems of records may in turn become part of the case record in (printed page 14746) this system. To the extent that copies of exempt records from those other systems of records are entered into this system, the Department of the Army hereby claims the same exemptions for the records from those other systems. (ii) Authority. 5 U.S.C. 552a (j)(2) and (k)(1) through (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided to the President and others are not compromised, to protect records used solely as statistical records, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records may be exempt from specific provisions of 5 U.S.C. 552a . (3) System identifier and name. A0025-55 OAA, Freedom of Information Act Program Files. (i) Exemption. During the processing of Freedom of Information Act (FOIA) requests, exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those other systems of records are entered into this system, the Department of the Army claims the same exemptions for the records from those other systems. (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(1) through (k)(7) . (iii) Reasons.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of

each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Part 252 RIN 0750-AF58 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD has issued a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to address requirements for validation of Taxpayer Identification Numbers as part of the Central Contractor Registration process. The DFARS changes are consistent with changes made to the Federal Acquisition Regulation. EFFECTIVE DATE: September 6, 2007. FOR FURTHER INFORMATION CONTACT: Ms. Felisha Hitt, Defense Acquisition Regulations System, OUSD (AT&L) DPAP (DARS), IMD 3D139, 3062 Defense Pentagon, Washington, DC 20301-3062. Telephone (703) 602-0310; facsimile (703) 602-7887. Please cite DFARS Case 2006-D037. SUPPLEMENTARY INFORMATION: A. Background DFARS 252.204-7004 contains a substitute paragraph for use with the clause at FAR 52.204-7, Central Contractor Registration, to address DoD-unique requirements relating to contractor registration in the Central Contractor Registration (CCR) database. This final rule amends DFARS 252.204-7004 for consistency with changes made to FAR 52.204-7 in Item I of Federal Acquisition Circular 2005-10, published at 71 FR 36923 on June 28, 2006. The changes address requirements for the Government to validate a contractor's Taxpayer Identification Number, and for the contractor to consent to this validation, as part of the CCR registration process. DoD published a proposed rule at 71 FR 2645 on January 22, 2007. DoD received no comments on the proposed rule. Therefore, DoD has adopted the proposed rule as a final rule without change. This rule was not subject to Office of Management and Budget review under Executive Order 12866, dated September 30, 1993. B. Regulatory Flexibility Act DoD certifies that this final rule will not have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601, et seq., because the rule relates to an administrative requirement for TIN validation, which is performed by the Government. Contractors need only provide consent for TIN validation as part of the CCR registration process. C. Paperwork Reduction Act The Paperwork Reduction Act does not apply, because the rule does not impose any information collection requirements that require the approval of the Office of Management and Budget under 44 U.S.C. 3501, et seq. List of Subjects in 48 CFR Part 252

Grants Officer Representatives, and other personnel to review the credentials of individuals requesting the authority to carry weapons (either government furnished or contractor acquired) in the performance of a U.S. government contract or grant; it allows agencies to report to Congress and other oversight organizations on the size of contractor and grantee presence in areas of combat operations or other significant military operations. Congress believes the system is necessary. Section 861 of FY 2008 NDAA provides that the Secretary of Defense, the Secretary of State, and the Administrator of USAID must agree to adopt a common database for contractors in Iraq and Afghanistan. SPOT is not used for intelligence gathering or vetting of personnel. Background checks of PSCs are conducted by the contractor and validated by the contracting officer. This validation is only annotated in SPOT. Comment: Applicable guidelines must be effectively disseminated to NGOs Response: Contracting Officers and Grants Officers will remain the primary point of contact for contractors and grantees on issues affecting performance. Rules impacting contractors across multiple agencies will be promulgated via the FAR with appropriate opportunities for contractor and public comment during the rulemaking process. Rules impacting grantees across multiple agencies will be promulgated by the Office of Management and Budget (OMB) Office of Federal Financial Management (OFFM) as part of its responsibility to issue government-wide grants policy. The DoD will ensure that a single location, readily accessible to both contractors and grantees, exists for the publication and maintenance of all guidance relating to PSC rules. The Department of State and USAID will provide any agency unique implementing guidance to DoD for publication on this same Web site. Areas for Clarification and Definitions Comment: ·Private Security Functions· needs to be better defined Response: The term ·private security functions· is defined by section 864 of the FY 2008 NDAA; the IFR used this definition. The Rule provides requirements for the management and oversight of companies contracted to perform private security functions and certain employees who may be required to carry and use arms in the performance of their duties. Companies and their personnel contracted to provide training, maintenance, or other support functions that are not required to carry a weapon in the performance of their duties are not addressed by this Rule. For clarification, in the Final Rule we have added ·in accordance with the terms of their contract·. Comment: Enforcement and liability pending adoption of FAR clauses Response: A FAR case has been opened to incorporate the required revisions based upon the publication of this Rule. Comment: The Rule

should address foreseeable issue concerning host nation law Response: The Geographic Combatant Commander has legal and political staffs capable of addressing the concerns expressed in this comment.

Periodic scans of organizational systems and real -time scans of files from external sources can detect malicious code. Malicious code can be encoded in various formats (e.g., 227 NIST SP 800-171A, p. 63. 228 NIST SP 800-171 Rev. 2, p. 42.

3.1.2 Virtual Disk Encryption and Volume Encryption ... 3.1.2 Virtual Disk Encryption and Volume Encryption Virtual disk encryption is the process of encrypting a file called a container , which can hold many files and folders, and permitting access to the data within the container only after proper authentication is provided, at which point the container is typically mounted as a virtual disk.

The standard would also require each regulated entity to determine the movement of ePHI through, into, and out of its information systems and to describe such movement in a network map. A regulated entity's network map would reflect where its technology assets are, for example, physically located at the regulated entity's worksite, or accessed through the cloud. As another example, a covered entity might determine that ePHI is created, received, maintained, or transmitted by one or more offshore business associates (i.e., persons that are located outside of the U.S.) for such services as claims processing, call center staffing, and technical support, activities that inherently involve ePHI. The technology assets used by the business associate to create, receive, maintain, or transmit ePHI are not a part of the covered entity's electronic information system, but do affect the confidentiality, integrity, or availability of ePHI and so would be required to be included in the network map of the covered entity. [447] Such assets would be considered part of the business associate's electronic information systems and therefore would need to be included in both its technology asset inventory and network map. Any technology assets used by the covered entity to create, receive, maintain, or transmit ePHI to the business associate would need to be accounted for in both its technology asset inventory and network map. Such technology assets would not be part of the business associate's technology asset inventory, but would need to be included on its network map. This proposed standard aligns with the Department's enhanced CPG for Asset Inventory, which requires that a regulated entity identify assets to more rapidly detect and respond to potential risks and vulnerabilities, [448] and is consistent with NCVHS' recommendation to require regulated entities to identify where all PHI is stored and to collect data on applications and systems used by the organization to create a systems inventory. [449] In 2003, the Department elected not to require regulated entities to conduct an inventory because we believed that regulated entities would understand that such an inventory is a vital component of the risk analysis, making it redundant of other requirements of the Security Rule. [450] The Department and NIST have provided extensive guidance, described below, about how to conduct such inventories as part of compliance with 45 CFR 164.308 . However, nearly 20 years of enforcement experience indicates that regulated entities routinely disregard this part of the process. OCR's investigations frequently find that organizations lack sufficient understanding of where all the ePHI entrusted to their care is located. [451] Understanding one's environment-particularly how ePHI is created and enters an organization, how ePHI flows through an organization, and how ePHI leaves an organization-is crucial to understanding the risks ePHI is exposed to throughout an organization. [452]

Table 9-Break-Even Thresholds by Number of Affected Individuals Baseline Affected individuals Regulated entities NPRM costs Unit cost (per individual record) Break-even threshold (NPRM cost ÷ unit cost) Percent decrease (threshold ÷ affected) × 100 High 64,551,397 \$2,251,258,305 \$498 4,521,423 7 Low 29,006,854 16.4 The analysis in table 9 suggests that this NPRM would break even (cost savings would match monetized costs incurred) if the number of affected individuals is reduced by approximately 4.5 million. In years with a high incidence of breaches, this would be a reduction of approximately 7 percent, and in low-incidence years this would be a decrease of 16.4 percent. Thus, if the proposed changes in the NPRM reduce the number of affected individuals by 7 to 16 percent, the rule would pay for itself. Alternatively, the same cost savings may be achieved by lowering the cost per affected individual's ePHI by 7 percent (\$35) and 16 percent (\$82), respectively. Table 10 analyzes the potential cost savings for regulated entities based on the annual number of large breaches of ePHI and the cost per breach, as shown below. Table 10-Break-Even Thresholds by Number of Large Breaches Baseline Breaches NPRM cost for regulated

entities Unit cost (per breach) Break-even threshold (NPRM cost ÷ unit cost) Percent decrease (threshold ÷ breaches) × 100 High 669 \$2,251,258,305 \$11,136,982 202 30.1 Low 440 58.9 In table 10, the Department assumes that the average cost per breach in industry reports (\$11.1 million, calculated as the average of the three highest values in table 9, adjusted for inflation) refers to large breaches of ePHI. The analysis in table 10 suggests that the NPRM would break even if the annual number of large breaches is reduced by approximately 202. In high-incidence years, this would be a reduction of approximately 30 percent, and in low-incidence years, this would be a decrease of 59 percent. Alternatively, the same cost savings may be achieved by lowering the cost per breach by 30 percent (\$3.4 million) and 9 percent (\$6.6 million), respectively. B. Regulatory Alternatives to the Proposed Rule The Department welcomes public comment on any benefits or drawbacks of the following alternatives it considered, but did not propose, while developing this proposed rule. We also request comment on whether the Department should reconsider any of the alternatives considered, and if so, why. No Changes to the Security Rule

Several days into the investigation of a Hepatitis A outbreak from chicken salad in one city, FDA learned that the chicken was ·cubed· at another facility in another city within the state, and transported to the ·manufacturing facility·. The source of the outbreak was the site where the chicken was ·cubed· by an ill employee; however, there were no records to indicate when the cubed product was shipped or received by the salad manufacturing facility. (printed page 71595) (Comment 83) One comment suggests that the final regulation should clarify that ·transportation record· includes the various documents that may be developed by a company that contain the information specified in the regulation. They do not believe that it would be necessary to include all of this information in one shipping document. The comment notes that industry currently collects much of the data that would be requested by FDA but these data are not found in one document, and in some instances, may be found at various locations within the manufacturing facility. Significant time and expense could be involved in making the modifications to the company's computer and recordkeeping systems to have a system that develops a transportation record that contains all of this information on one form. Such a requirement would be unreasonably onerous, particularly if the company's system is designed to make certain that the company can provide all of this information to the agency within the specified time. The respondent asks the agency to clarify in the final rule that it is not necessary to develop one transportation record that contains all of the information in a single form. (Response) FDA confirms that it is not necessary to develop one record that contains all of the information. FDA's intent is to have as little impact as possible on current recordkeeping practices if those records can meet the requirements of these regulations. The final regulation has been clarified to explicitly provide in § 1.360 that you must create the required records when you receive and release food, except to the extent that the information is contained in existing records. FDA is requiring that specific information be kept by a covered person, but is not specifying the form or type of system in which those records must be maintained. The required information may be contained entirely in one record or spread among many different records. The person subject to these regulations is responsible for ensuring that it keeps all applicable records and that those records are available to FDA under the record availability requirements in § 1.361 of this final rule. (Comment 84) A few comments note that the recordkeeping requirements under existing FDA regulations, such as Substances Prohibited From Use in Animal Food or Feed (21 CFR part 589), Current Good Manufacturing Practice for Medicated Feeds (21 CFR part 225), and Fish and Fishery Products (seafood Hazard Analysis Critical Control Point (HACCP)) (

ion would help security to more effectively compete with other agency objectives. - Need guidance on what to do about the physical distribution of the database (including all the data on PC floppies). - Need guidance on the monitoring of IT resources in light of the potential access by one individual to huge repositories of information from many agencies. - Need guidance on categorization and labelling. - Need guidance on how to administer security in a decentralized environment. - Need guidance on uploading/downloading between PCs and mainframes. - Need guidance and policy for maintaining data integrity In a cooperative processing environment.

). It is any information system, including any telecommunications system, used or operated by an agency or by a contractor of an agency, or other organization on behalf of an agency. (1) The function, operation, or use of which: (i) Involves intelligence activities; (ii) Involves cryptologic activities related to national security; (iii) Involves command and control of military forces; (iv) Involves equipment that is an integral part of a weapon or weapons system; or (v) Is critical to the direct fulfillment of military or intelligence missions but this does not include a

system that is to be used for routine administrative and business applications, including payroll, finance, logistics, and personnel management applications; or (2) Is protected at all times by procedures established for information that have been specifically authorized under criteria established by an Executive order or an Act of Congress to be kept classified in the interest of national defense or foreign policy. Information technology, in lieu of the definition at FAR 2.1, and supply chain risk, are defined in the clause at 252.239-7018, Supply Chain Risk. 239.7303 Authorized individuals. (a) Subject to 239.7304, the following individuals are authorized to take the actions authorized by 239.7305: (1) The Secretary of Defense. (2) The Secretary of the Army. (3) The Secretary of the Navy. (4) The Secretary of the Air Force. (b) The individuals authorized at paragraph (a) may not delegate the authority to take the actions at 239.7305 or the responsibility for making the determination required by 239.7304 to an official below the level of: (1) For the Department of Defense, the Under Secretary of Defense for Acquisition, Technology, and Logistics; and, (2) For the military departments, the senior acquisition executive for the department concerned. 239.7304 Determination and notification. The individuals authorized in 239.7303 may exercise the authority provided in 239.7305 only after: (a) Obtaining a joint recommendation by the Under Secretary of Defense for Acquisition, Technology, and Logistics and the Chief Information Officer of the Department of Defense, on the basis of a risk assessment by the Under Secretary of Defense for Intelligence, that there is a significant supply chain risk to a covered system; (b) Making a determination in writing, in unclassified or classified form, with the concurrence of the Under Secretary of Defense for Acquisition, Technology, and Logistics, that: (1) Use of the authority in 239.7305(a)(b) or (c) is necessary to protect national security by reducing supply chain risk; (2) Less intrusive measures are not reasonably available to reduce such supply chain risk; and (3) In a case where the individual authorized in 239.7303 plans to limit disclosure of information under 239.7305(d), the risk to national security due to the disclosure of such information outweighs the risk due to not disclosing such information; and

(i) If DSS determines that a company is under FOCI, DSS will assess the extent and manner to which the FOCI may result in unauthorized access to classified information or adverse impact on the performance of classified contracts and the type of actions, if any, that would be necessary to mitigate or negate the associated risks to a level deemed acceptable to DSS. An analysis of some of the FOCI factors may clearly identify risk; while others may result in circumstances that would mitigate or negate risks. Therefore, these factors must be considered in the aggregate with regard to the foreign interest that is the source of the FOCI, the country or countries in which the foreign interest is domiciled and has its principal place of business (if not in the country of domicile), and any other foreign country that is identified by DSS because it is a substantial source of the revenue for, or otherwise has significant ties to, the foreign interest. DSS will consider the following FOCI factors and any other relevant information in the context of threat, vulnerability, and sensitivity of the classified information required for current or prospective contract performance when rendering a risk management assessment and determination of the acceptability of a company's FOCI action plan: (A) Record of economic and government espionage against U.S. targets. (B) Record of enforcement and/or engagement in unauthorized technology transfer. (C) Record of compliance with pertinent U.S. laws, regulations, and contracts. (D) The type and sensitivity of the information that will be accessed. (E) The source, nature, and extent of FOCI, including, but not limited to, whether a foreign interest holds a majority or substantial minority position in the company, taking into consideration the immediate, intermediate, and ultimate parent companies of the company or prior relationships between the U.S. company and the foreign interest. (F) The nature of any relevant bilateral and multilateral security and information exchange agreements, (e.g., the political and military relationship between the United States Government (USG) and the government of the foreign interest). (G) Ownership or control, in whole or in part, by a foreign government. (H) Any other factor that indicates or demonstrates a capability on the part of foreign interests to control or influence the operations or management of the business organization concerned. (ii) As part of its FOCI assessment and evaluation of any FOCI action plan, DSS will also request and consider counterintelligence (CI) and technology transfer risk assessments and any available intelligence from all appropriate USG sources. DSS will request these assessments as soon as practicable, for the company itself and for all business entities in the company's ownership chain.

Another asked about validating compliance for assets that changed asset categories when transitioning from Level 2 certification to Level 3 certification. One comment said it was that Level 2 certification is not clearly identified as a prerequisite for Level 3 certification, and

that organizations might try to bypass Level 2. One comment asked whether those entities that would need a CMMC level 3 assessment could seek a combined Level 2 and Level 3 certification from the DIBCAC to reduce cost to the OSC. One comment sought clarification of how long an OSC would be prohibited from seeking additional contract awards if a Level 3 certification expired. Two comments were concerned about the DIBCAC's ability to terminate a Level 3 assessment if the review identifies a Level 2 requirement that is not met. Response: For CMMC Level 3, the DoD selected a subset of NIST SP 800-172 Feb2021 requirements for enhanced safeguarding. The CMMC Level 3 supplemental documents were not finalized prior to publication of the Proposed Rule. DoD's final determination of the specific subset of NIST SP 800-172 Feb2021 requirements is included in this final rule, which defines the ODPs for Level 3 in table 1 to § 170.14(c)(4). DoD will update the rule when required to change the security requirements, to include CMMC Level 3. DoD has reviewed and declined the recommendation to conduct a pilot prior to phasing in CMMC Level 3 requirements. Given the evolving cybersecurity threat, DoD's best interests are served by ensuring that the selected CMMC Level 3 NIST SP 800-172 Feb2021 security requirements are in place to provide enhanced protections for sensitive DoD CUI. In those cases when DCMA DIBCAC identifies that a Level 2 security requirement is NOT MET, DCMA DIBCAC may allow for remediation, place the assessment process on hold, or may immediately terminate the Level 3 assessment, depending on significance of the NOT MET security requirement(s) and the nature of the required remediation. The determination of whether a NOT MET requirement is significant is reserved for the judgment of the DCMA DIBCAC. The rule has been updated to clarify that DCMA DIBCAC has the responsibility to validate compliance of all assets that changed asset category (i.e., CRMA to CUI Asset) or assessment requirements (i.e.,

Several comments expressed disagreement with assumptions supporting the cost estimate, namely that implementation costs to comply with the requirements of FAR clause 52.204-21 and DFARS clause 252.204-7012 predate and are not included as CMMC costs. These comments assert that the cost of CMMC compliance should include those costs, and therefore dwarfs the cost of CMMC certification. They further assert that DoD's position does not account for those contractors who have only recently joined the DIB marketplace or those that aspire to do so. The concern expressed in the comments is that the cost of standing up an infrastructure to achieve and maintain DoD cybersecurity requirements regarding the protection of FCI and CUI, combined with CMMC assessment costs, is prohibitive and will create a lack of diverse suppliers. Two commenters asserted the CMMC Program expanded application of DFARS clause 252.204-7012 requirements due to a perceived extension of those requirements to additional organizations, such as External Service Providers (ESPs). One of the commenters further speculated that CMMC requirements may decrease the availability of ESPs that are available and suitable to support DIB members as needed to comply with CMMC requirements. Another commenter stated that this scope expansion increases direct implementation and compliance costs above and beyond the CMMC Program's estimated assessment costs. The comment cites the introduction of the terms "Security Protection Assets" and "Security Protection Data" as extending applicability of those requirements and incurring the additional direct implementation and compliance costs. Lastly, the comment notes these changes will drive costs to "rip and replace" existing tools and likely purchase more expensive FedRAMP or CMMC-certified tools. One comment indicated that, while compliance with NIST SP 800-171 was required by December 31, 2017, compliance with NIST SP 800-171A Jun2018 increases requirements and cost because NIST SP 800-171A Jun2018 emphasizes process and documentation in addition to the intent of the security requirement. Two comments pointed out that some contractors may need to accelerate remediation efforts and close out POA&Ms under existing DoD contracts that are subject to DFARS clause 252.204-7012 to meet CMMC requirements. These comments requested that since these contractors will now be faced with accelerating close-out of their POA&Ms, which will incur additional costs, that DoD account for those costs in the estimate and potentially allow for recovery of those costs. One comment asserts that CMMC assessment failures, remediation implementation, and subsequent reassessments will be very costly in both time and money. Response: 81 FR 72990

From the NIST SP 800-172 Rev 3 Final Public Draft: Organizations also use automated mechanisms to implement NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 and maintain authoritative (i.e., up-to-date, complete, accurate, and available) 961

From the NIST SP 800-172 Rev 3 Final Public Draft: 40 (PPD-40) National Continuity Policy, within expected timelines without the information or information 2938 system. "Federal Civilian Enterprise Essential (FCEE): The information or information system serves a critical function in

maintaining the security and resilience of the federal civilian enterprise. [10] impact With respect to security, the effect on organizational operations, organizational assets, individuals, other organizations, or the Nation (including the national security interests of the United States) of a loss of confidentiality, integrity, or availability of information or a system. With respect to privacy, the adverse effects that individuals could experience when an information system processes their PII. impact value The assessed worst-case potential impact

(Response) In the final rule, all foreign persons are excluded from all requirements in this rule, except for foreign persons who transport food in the United States. Because all foreign persons who transport food in the United States are currently subject to FMCSA regulations as interstate transporters, and can meet the requirements of transporters in subpart J of this final rule by keeping records already required by FMCSA, the costs of compliance for these facilities, including the costs for the records access requirement, are assumed to be zero. (Comment 213) One comment questions the implied assumption in the PRIA that foreign transporters share the cost burden with other foreign facilities when foreign transporters are not covered by the rule. (Response) Foreign persons who transport food in the United States are covered by this final rule. The revised costs of compliance by these facilities to establish and maintain records are assumed to be zero because they will be in compliance with this final rule if they keep the records currently required by FMCSA for interstate transporters. 10. Compliance Dates Several comments suggest changes in the compliance dates. In the design of the regulation, the compliance dates are used primarily to address regulatory flexibility considerations. Consequently, these comments are treated in the regulatory flexibility section of the final analysis. G. Summary of the Costs and Benefits of the Final Rule and Policy Options Considered The revisions to the cost estimates based on comments to the proposed rule and on changes in records requirements between the proposed and final rule result in estimated costs of approximately \$1.41 billion expressed in present value terms, using a 7-percent discount rate. Using a discount rate of 3 percent, the estimated costs of the final rule expressed in present value terms are approximately \$1.94 billion. Costs for learning, records redesign, and planning for records access requests are one-time costs incurred in the first 2 years following publication of the final rule. Additional records maintenance costs and records retention costs are incurred each year following publication of the final rule, beginning in the second year for large and small firms and in the third year for very small firms. Learning costs and records access planning costs for new entrants are also incurred each year following publication of the final rule beginning after the second year. The details of the assumptions used to estimate the costs are provided in the PRIA. The estimated total cost is computed by summing the costs estimated for learning, records redesign, additional records maintenance, records retention, and planning for a records access request. The annual and total costs of the final rule are reported in table 15 of this document. Table 15. Estimated Annual and Total Recordkeeping Costs 1 21 CFR Section Costs (in dollars) 1.337, 1.345, and 1.352 (learning) \$85,082,000

CIS Safeguard 4.9 · Configure Trusted DNS Servers on Enterprise Assets Configure trusted DNS servers on enterprise assets. Example implementations include: configuring assets to use enterprise-controlled DNS servers and/or reputable externally accessible DNS servers. Implementation Groups: 2,3 Asset Type: devices Security Function: protect Parent Control: Secure Configuration of Enterprise Assets and Software

means authentication of the user's identity through verification of at least two of the following three categories: (1) Information known by the user, including but not limited to a password or personal identification number (PIN). (2) Item possessed by the user, including but not limited to a token or a smart identification card. (3) Personal characteristic of the user, including but not limited to fingerprint, facial recognition, gait, typing cadence, or other biometric or behavioral characteristics. Password means confidential authentication information composed of a string of characters, such as letters, numbers, spaces, and other symbols. Physical safeguards are physical measures and related policies and procedures to protect a covered entity's or business associate's relevant electronic information systems, and related facilities and equipment, from natural and environmental hazards and unauthorized intrusion. Relevant electronic information system means an electronic information system that creates, receives, maintains, or transmits electronic protected health information or that otherwise affects the confidentiality, integrity, or availability of electronic protected health information. Risk means the extent to which the confidentiality, integrity, or availability of electronic protected health information is threatened by a potential circumstance or event. Security or security measures encompass all of the administrative,

physical, and technical safeguards in or applied to an information system. Security incident means any of the following: (1) The attempted or successful unauthorized access, use, disclosure, modification, or destruction of information in an information system. (2) The attempted or successful unauthorized interference with system operations in an information system. Technical controls means the technical mechanisms contained in the hardware, software, or firmware components of an electronic information system that are primarily implemented and executed by the electronic information system to protect the information system and data therein. Technical safeguards means the technology, technical controls, and related policies and procedures governing the use of the technology that protects and controls access to electronic protected health information. Technology asset means the components of an electronic information system, including but not (printed page 1012) limited to hardware, software, electronic media, information, and data. Threat means any circumstance or event with the potential to adversely affect the confidentiality, integrity, or availability of electronic protected health information. User means a person with authorized access. Vulnerability means a flaw or weakness in an information system, information system security procedures, design, implementation, or technical controls that could be intentionally exploited or accidentally triggered by a threat. Workstation

CIS Safeguard 3.2 · Establish and Maintain a Data Inventory Establish and maintain a data inventory, based on the enterprise's data management process. Inventory sensitive data, at a minimum. Review and update inventory annually, at a minimum, with a priority on sensitive data. Implementation Groups: 1,2,3 Asset Type: data Security Function: identify Parent Control: Data Protection

This rule does not duplicate, overlap, or conflict with any other Federal rules. There are no known significant alternative approaches to the proposed rule that would meet the proposed objectives. DoD invites comments from small business concerns and other interested parties on the expected impact of this rule on small entities. DoD will also consider comments from small entities concerning the existing regulations in subparts affected by this rule in accordance with 5 U.S.C. 610 . Interested parties must submit such comments separately and should cite 5 U.S.C. 610 (DFARS Case 2018-D050) in correspondence. VI. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). List of Subjects in 48 CFR Parts 204 and 252 Government procurement Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204 and 252 are proposed to be amended as follows: 1. The authority citation for 48 CFR parts 204 and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 . PART 204·ADMINISTRATIVE MATTERS 2. Amend section 204.7104-1 by· (printed page 58364) a. In paragraph (b)(3)(iii), removing ·subsection· and adding ·section· in its place; b. Revising paragraph (b)(3)(iv). The revision reads as follows: 204.7104-1 Criteria for establishing. * * * * * (b) * * * (3) * * * (iv) When the price for items not separately priced is included in the price of another contract line or subline item, it may be necessary to withhold payment on the priced contract line or subline item until the included line or subline items that are not separately priced have been delivered. See the clause at 252.204-7002, Payment for Contract Line or Subline Items Not Separately Priced. 3. Revise section 204.7109 to read as follows: 204.7109 Contract clauses. (a) Use the clause at 252.204-7002, Payment for Contract Line or Subline Items Not Separately Priced, in solicitations and contracts when the price for items not separately priced is included in the price of another contract line or subline item. (b) Use the clause at 252.204-7006, Billing Instructions, in solicitations and contracts if Section G includes· (1) Any of the standard payment instructions at PGI 204.7108(b)(2); or (2) Other payment instructions, in accordance with PGI 204.7108(d)(12), that require contractor identification of the contract line item(s) on the payment request. PART 252·SOLICITATION PROVISIONS AND CONTRACT CLAUSES 4. Revise section 252.204-7002 to read as follows: 252.204-7002 Payment for Contract Line or Subline Items Not Separately Priced. As prescribed in 204.7109(a), use the following clause: Payment for Contract Line or Subline Items Not Separately Priced (Date)

proposed. The software can be managed by the developers as an open-source project shared publicly using version control platforms, such as Github, or the software can be proprietary and kept private. Development patterns can be leveraged to enable smart contract upgradability (e.g., a registry contract that points to the latest version of the main contract of the system or an interface contract that is inherited by the system and defines a set of key functions and

parameters). Periodic thirdparty audits, automated tests, and reports can also be performed and disclosed to help assess whether the rules are properly enforced.

3.5.1 PCD: Microsoft* Wndows NT· POSIX Subsystem POSIX Conformance 151-2MSC0013 Issued: 11/17/94
Type: Cooperating Hosted Document, August 1995 Product Supplier: Microsoft Corporation Product:
Microsoft* Windows NT· POSIX Subsystem Version 3. 3.5.1 C Compiler: Microsoft* 32-bit C/C+ +
Optimizing Compiler, Version 9. 3.5.1 PCD: Microsoft* Wndows NT· POSIX Subsystem POSIX Conformance
Document, August 1995 GTI - Not Provided by Product MFS - Not Provided by Product Computer Hardware
Supplier: Intel Computer Hardware Product: Pentium LPX Pentium 100 Host & Development Operating
System Supplier: Microsoft Corporation Host & Development Operating System: Microsoft* Wndows NT·
MC - Not Provided by Product AP - Not Provided by Product Workstation, Version 3.

All information system authorized users will receive training on the security risks associated with their user activities and responsibilities under the NISP. The contractor will determine the appropriate content of the training, taking into consideration assigned roles and responsibilities, specific security requirements, and the information system to which personnel are authorized access.

(j) Temporary help suppliers. A cleared temporary help supplier, or other contractor who employs cleared individuals solely for dispatch elsewhere, will be responsible for ensuring that required briefings (both initial and refresher training) are provided to their cleared personnel. The temporary help supplier or the using contractor may conduct these briefings. (printed page 83336)

(k) Refresher training. The contractor will provide all cleared employees with security education and training every 12 months. Refresher training will reinforce the information provided during the initial security briefing and will keep cleared employees informed of changes in security regulations and should also address issues or concerns identified during contractor self-reviews.

Training methods may include group briefings, interactive videos, dissemination of instructional materials, or other media and methods. Contractors will maintain records about the programs offered and employee participation in them. (l) Debriefings. Contractors will debrief cleared employees and annotate the debriefing in the appropriate contractor records when access to classified information is no longer needed; at the time of termination of employment (discharge, resignation, or retirement); when an employee's eligibility for access to classified information is terminated, suspended, or revoked; and upon termination of the entity eligibility determination. §.117.13

Classification. (a) Original classification. Only a USG official designated or delegated the authority in writing can make an original classification decision. (1) An OCA classifies information pursuant to E.O. 13526 and 32 CFR part 2001 , designates and marks it as TOP SECRET, SECRET, or CONFIDENTIAL, and, except as provided by statute, may use no other terms to identify classified information. (2) The designation UNCLASSIFIED is used to identify information that does not meet the criteria for classification in accordance with E.O. 13526 . In accordance with 32 CFR 2002 , CUI implementing guidance (including the Marking Handbook) and any GCA-provided guidance, CUI commingled with classified information must be marked as CUI to alert users to its presence and sensitivity. The CUI regulation, guidance, and handbook are available at: <https://www.archives.gov/cui> . (b) Derivative classification.

Under CMMC Level 2 (NIST SP 800-171 Rev 3), organizations must implement specific controls addressing this area. Key considerations include: 1. The specific NIST SP 800-171 controls that apply to this scenario 2. Documentation requirements for the SSP 3. Evidence needed for C3PAO assessment 4. Cost-effective implementation options for different organization sizes Organizations should reference the specific control families in NIST SP 800-171 Rev 3 and consult the CMMC Assessment Guide Level 2 for detailed assessment objectives. A Registered Practitioner (RP) can provide organization-specific guidance.

However, several limiting provisions exist before the Government can exercise its authorities under section 806. First, use of section 806 authorities is limited to the procurement of NSS or of covered items of supply used within NSS. Section 806 defines a ·covered item of supply· as ·an item of information technology . . . that is purchased for inclusion in (an NSS), and the loss of integrity of which could result in a supply chain risk· to the entire system. Therefore, though the clause will be inserted in all information-technology contracts, these authorities will not be able to be utilized for all information and communication technology in all systems, but rather only in those meeting the criteria stated above. Second, the decision to exclude a source under section 806 can only be made by the ·head of a covered agency·, limited by definition to the Secretary of Defense and the Secretaries of the military departments with delegation limited to officials at or

above the level of the service acquisition executive for the agency. Third, the head of a covered agency seeking to exercise the authority of section 806 must obtain a joint recommendation from the Under Secretary of Defense for Acquisition, Technology, and Logistics (USD(AT&L)) and the Chief Information Officer of the Department of Defense (DoD CIO), based on a risk assessment from the Under Secretary of Defense for Intelligence (printed page 69269) (USD(I)) that there is significant supply chain risk to a particular NSS. Fourth, the head of a covered agency, with the concurrence of the USD(AT&L), must make a written determination that the use of section 806 authority is necessary to protect national security by reducing supply chain risk and that less intrusive measures are not reasonably available to reduce such supply chain risk. Fifth, notice of each determination to exercise section 806 authorities must be provided in advance to the appropriate congressional committees. Finally, section 806 expires on September 30, 2018 (see section 806 of FY 2013 NDAA, Public Law 112-239). Section 806 also provides that the head of a covered agency may limit, notwithstanding any other provision of law, in whole or in part, the disclosure of information relating to the basis for carrying out a covered procurement action if the head of a covered agency, with the concurrence of the USD (AT&L), determines in writing that the risk to national security due to disclosure of such information outweighs the risk due to not disclosing such information. If the Government exercises the authority provided to limit disclosure of information, no action undertaken by the Government under such authority shall be subject to review in a bid protest before the Government Accountability Office or in any Federal court. III. Executive Orders 12866 and 13563

(1) The request is made by a citizen of the United States or a United States corporation, and such citizen or corporation certifies that the technical data requested is required to enable it to submit an offer, or determine whether it is capable of submitting an offer to provide the product to which the technical data relates to the United States or a contractor with the United States. However, DoD Components may require the citizen or corporation to pay a deposit in an amount equal to not more than the cost of complying with the request, which will be refunded upon submission of an offer by the citizen or corporation; (2) The release of technical data is requested in order to comply with the terms of an international agreement; or, (3) The Component determines in accordance with § 286.24(c)(4)(i)(D) that such a waiver is in the interest of the United States. § 286.27 Fees for research data. Research data described in § 286.2, definition "Agency record" obtained by the DoD Component from a grant recipient solely in response to a request submitted by a FOIA requester, may charge that requester a reasonable fee equaling the full incremental cost of obtaining the research data. The fee should reflect costs incurred by the Component, grant recipient, and sub-recipients. This fee is in addition to any fees the Component may assess under the FOIA. Subpart F-Education and Training § 286.30 Purpose and responsibility. (a) Purpose. The purpose of the Component FOIA educational and training programs is to promote a positive attitude among DoD personnel and raise the level of understanding and appreciation of the DoD FOIA Program. Fulfilling this purpose will improve customer service with members of the public and improve the public trust in the Department of Defense. (b) Responsibility. Each DoD Component shall establish educational and training programs on the provisions and requirements of this part. These should be targeted toward developing in all Component personnel a general understanding and appreciation of the DoD FOIA Program. The training programs should be focused on providing personnel involved in the day-to-day processing of FOIA requests with a thorough understanding of the procedures outlined in this part. (c) Scope and principles. Each DoD Component shall design its FOIA educational and training programs to fit the particular requirements of its personnel, dependent upon their degree of involvement in implementing this part. These programs should be designed for two target audiences; those personnel who are involved in the day-to-day processing of FOIA requests, and those staff personnel who provide search and/or review staff support to the Component FOIA process. The programs should be designed to accomplish the following objectives: (printed page 71867) (1) Familiarize personnel with the requirements of the FOIA and its implementation by this part.

ature Parameter Sets. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-230. [Forthcoming: will be available at <https://csrc.nist.gov/publications>]. - [25] National Institute of Standards and Technology (2016) Submission Requirements and Evaluation Criteria for the Post-Quantum Cryptography Standardization Process. Available at <https://csrc.nist.gov/CSRC/media/Projects/Post-Quantum-Cryptography/documents/call-for-proposals-final-dec-2016.pdf>. - [26] Alagic G, Apon D, Cooper DA, Dang QH, Dang T, Kelsey JM, Lichtinger J, Liu YK, Miller CA, Moody D, Peralta R, Perlner RA, Robinson A, Smith-Tone D (2022)

Status Report on the Third Round of the NIST Post-Quantum Cryptography Standardization Process. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Interagency or Internal Report (IR) NIST IR 8413-upd1, includes updates as of September 26, 2022. <https://doi.org/10.6028/NIST.IR.8413-upd1>. - [27] Hülsing A, Kudinov M (2022) Recovering the Tight Security Proof of SPHINCS+. *Advances in Cryptology -ASIACRYPT 2022*, eds Agrawal S, Lin D (Springer Nature Switzerland, Cham), pp 3-33. https://doi.org/10.1007/978-3-031-22972-5_1. - [28] Stern J, Pointcheval D, Malone-Lee J, Smart NP (2002) Flaws in Applying Proof Methodologies to Signature Schemes. *Advances in Cryptology -CRYPTO 2002*, ed Yung M (Springer Berlin Heidelberg, Berlin, Heidelberg), pp 93-110. https://doi.org/10.1007/3-540-45708-9_7. - [29] Cremers C, Düzlül S, Fiedler R, Janson C, Fischlin M (2021) BUFFing Signature Schemes Beyond Unforgeability and the Case of Post-Quantum Signatures. *2021 IEEE Symposium on Security and Privacy (SP)* (IEEE Computer Society, Los Alamitos, CA, USA), pp 1696-1714. <https://doi.org/10.1109/SP40001.2021.00093>. - [30] Moriarty K, Kaliski B, Jonsson J, Rusch A (2016) PKCS #1: RSA Cryptography Specifications Version 2.2. (Internet Engineering Task Force (IETF)), IETF request for comments (RFC) 8017.

Information about an individual that identifies, relates, or is unique to, or describes him or her, e.g., a social security number, age, military rank, civilian grade, marital status, race, salary, home/office phone numbers, etc. (r) Persistent cookies. Cookies that can be used to track users over time and across different Web sites to collect personal information. (s) Personal Identifier. A name, number, or symbol that is unique to an individual, usually the person's name or SSN. (t) System of Records. A group of records under the control of the DA from which information is filed and retrieved by individuals' names or other personal identifiers assigned to the individuals. System notices for all systems of records must be published in the Federal Register. A grouping of records arranged chronologically or subjectively that are not retrieved by individuals' names or identifiers is not a Privacy Act system of records, even though individual information could be retrieved by individuals' names or personal identifiers, such as through a paper-by-paper search. (u) Privacy Advisory. A statement required when soliciting personally identifying information by a Department of the Army Web site and the information is not maintained in a system of records. The Privacy Advisory informs the individual why the information is being solicited and how it will be used. (v) Privacy Impact Assessment (PIA). An analysis, which considers information sensitivity, vulnerability, and cost to a computer facility or word processing center in safeguarding personal information processed or stored in the facility. (w) Privacy Act (PA) Request. A request from an individual for information about the existence of, access to, or amendment of records pertaining to that individual located in a Privacy Act system of records. The request must cite or implicitly refer to the Privacy Act of 1974. (x) Protected Personal Information. Information about an individual that identifies, relates to, is unique to, or describes him or her (e.g., home address, date of birth, social security number, credit card, or charge card account, etc.). (y) Records. Any item, collection, or grouping of information, whatever the storage media (e.g., paper, electronic, etc), about an individual that is maintained by a DOD Component, including but not limited to, his or her education, financial transactions, medical history, criminal or employment history and that contains his or her name, or the identifying number, symbol, or other identifying particular assigned to the individual, such as a finger or voice print or a photograph. (printed page 46071) (z) Records Maintenance and Use. Any action involving the storage, retrieval, and handling of records kept in offices by or for the agency. (aa) Review Authority.

One comment suggested that audit standards be determined for CMMC assessments. Two comments asked for clarification regarding references provided in the model, whether all references must be reviewed, and if the requirements within the references must also be achieved. Response: The Department has reviewed definitions of audit and assessments and determined 'assessment' best meets the goals of the CMMC Program. The cybersecurity standard requirements for the different CMMC Levels are set forth in §.170.14 and clarify references for the security requirements. Comment: Many commenters were concerned about the lack of waivers or POA&Ms. Several commenters commented that not allowing waivers is impractical and will impact the ability of businesses to qualify for contract award. Commenters asked for clarification on the differences between POA&M that are not allowed by CMMC and the plans of action as required in the CMMC Level 3 control (now CMMC Level 2 under CMMC 2.0), CA.2.159 (now CA.L2-3.12.2 under CMMC 2.0). Many noted that POA&Ms are necessary when managing activities like system upgrades, vendor changes, and company acquisitions to avoid temporarily falling out of compliance. Response: Under certain circumstances, the CMMC Program does permit contract award to organizations that have an approved and time limited POA&M. See §.170.21 for additional information on POA&Ms. There is no process for organizations to request waiver of CMMC

solicitation requirements. DoD internal policies, procedures, and approval requirements will govern the process for DoD to waive inclusion of the CMMC requirement in the solicitation. 22. The Accreditation Body and C3PAOs Comment: Many commenters had questions and concerns about the management of the Accreditation Body and C3PAOs. A few commenters suggested using a government entity instead of the Accreditation Body construct to manage assessments. Commenters asked about the governance, resourcing, and oversight of the Accreditation Body with respect to CMMC training and assessments. Commenters expressed concerns such as who would make final decisions about CMMC issues, the lack of clearly defined roles and responsibilities for CMMC governance, and the long-term effectiveness of the Accreditation Body staffed by an all-volunteer workforce. One comment asked how the Accreditation Body can legally license training when CMMC Program information is available for free. Response: The decision to use a non-governmental Accreditation Body was made because the DoD determined that there was insufficient capacity within the DoD to manage assessor training and assessments for all defense contractors who need to comply with CUI protection policies. The DoD CMMC PMO provides oversight of the Accreditation Body and is also responsible for developing, updating, maintaining, and publishing the CMMC Model, CMMC Assessment Guides, and policies for implementation of the CMMC Program.

atile user data. Storage heaps may also be ROM-based. As part of the cold boot sequence (i.e., a hard reset), in addition to reinitializing the dynamic area of RAM, the storage area is erased [PPC04]. Besides memory, SD cards may also incorporate other types of peripherals such as wireless communications or camera cards.

If an XCCDF component has multiple `<xccdf:check-content-ref>` elements, then check processing SHALL be performed according to [XCCDF:7.2.3.5.1] with the following changes: 6. Regarding the definition and use of `<xccdf:Profile>` elements, reported `<xccdf:setvalue>` elements SHALL include all those values that are exported by the reported rules. The specific settings are those determined by the reported `<xccdf:Profile>`. 7. The `<xccdf:identity>` element SHALL identify the security principal used to access rule evaluation on the target(s). This will include the identity name or username used to perform the evaluation. 8. Each IP address(es) associated with the `<xccdf:target>` SHALL be enumerated using the `<xccdf:target-address>` element. 9. An `<xccdf:target-id-ref>` SHALL be specified with a `@system` attribute of 'http://scap.nist.gov/schema/asset-identification/1.1', an `@href` attribute value of "", and a `@name` attribute value of the ID of the `<ai:asset>` element in the ARF that this `<xccdf:TestResult>` is about. 10. The `<xccdf:rule-result>` elements report the result of the application of each selected rule [XCCDF:6.6.2]. The `@role`, `@severity`, and `@weight` attributes of the `<xccdf:rule-result>` element SHALL be provided to indicate their values used during assessment. The `<xccdf:check/xccdf:check-content-ref>` element SHALL record the reference to the checking system specific result component report ID and check name within the result file using the `@href` and `@name` attributes, respectively. The `@href` attribute SHALL contain '#' + the `@id` of the `<arf:report>` containing the check result. This approach provides traceability between XCCDF and check results. Note that if `@multi-check` is not set to 'true' and the `<xccdf:rule-result>` represents a group of checks, then the `@name` attribute SHALL be omitted. See the example below the next requirement. 11.

Exemption. During the processing of a Freedom of Information Act/Privacy Act request, exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those other systems of records are entered into this system, the NRO hereby claims the same exemptions for the records from those other systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2), (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, and to preserve the confidentiality and integrity of Federal evaluation materials. The exemption rule for the original records will identify the specific reasons

why the records are exempt from specific provisions of 5 U.S.C. 552a . (8) System identifier and name. QNRO-27, Legal Records. (i) Exemption. Any portion of this system of records which falls within the provisions of 5 U.S.C. 552a(k)(2) and (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a (k)(2) and (k)(5). (iii) Reasons. (A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence.

3.4.2 3.4.2
..... OS
.....
..... 3.

. Instead, as discussed in greater detail below, we propose to clearly delineate maintenance implementation specifications for specific standards, when applicable. We believe this approach would clarify how maintenance requirements relate to specific security measures and would remove any ambiguity about the need for regulated entities to regularly review, test, and modify measures as reasonable and appropriate. We further discuss maintenance provisions below for each safeguard. 4. Request for Comment The Department requests comment on the foregoing proposals, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular: a. Whether removing the distinction between required and addressable implementation specifications would result in unintended negative consequences for regulated entities. If so, please explain and provide a recommendation for how the Department should clarify how regulated entities are required to implement the security measures described in the proposed rule. b. Whether the Department should include other factors in 45 CFR 164.306(b) for regulated entities to consider when selecting the security measures that they will implement to meet the requirements of the Security Rule. If so, please explain. c. Whether the factor proposed by the Department at proposed 45 CFR 164.306(b)(2)(v) would help regulated entities identify reasonable and appropriate security measures. d. Whether the Department's proposals sufficiently clarify that a regulated entity is expected to modify its security measures in response to changes in the environment in which health care is provided, including, but not limited to, the adoption of new technology, the evolution of existing technology, and the emergence of new threats. e. Whether the proposals sufficiently take into account the needs and capabilities of small health care providers and rural health care providers, as required by the statute. If not, please explain and include a recommendation for ways that the Department could better account for such needs and capabilities while adequately ensuring the confidentiality, integrity, and availability of ePHI that they create, receive, maintain, or transmit. The recommendations should also take into consideration the effect of the actions taken by small and rural health care providers on the ePHI that is created, received, maintained, or transmitted by other regulated entities with whom small and rural health care providers interact. D. Section 164.308-Administrative Safeguards Section 164.308 of title 45 CFR contains the administrative safeguards that a regulated entity must implement, consistent with the general requirements described in 45 CFR 164.306 . All of the standards and implementation specifications found in the Administrative Safeguards section refer to administrative functions, such as policies and procedures that must be in place for the management and execution of security measures.

Today, DoD prime contractors must include DFARS clause 252.204-7012 in subcontracts for which performance will involve covered defense information, but this does not provide the Department with sufficient insights with respect to the cybersecurity posture of all members of a multi-tier supply chain for any given program or technology development effort. The revised CMMC Program requires prime contractors to flow down appropriate CMMC Status requirements, as applicable, to subcontractors throughout their supply chain(s). Given the size and scale of the DIB, the Department cannot scale its existing cybersecurity assessment capability to conduct on-site assessments of approximately 220,000 DoD contractors and subcontractors every three years. The Department's existing assessment capability is best suited for conducting targeted assessments for the relatively small subset of DoD contractors and subcontractors that support designated high-priority programs involving CUI. CMMC addresses the Department's scaling challenges by utilizing a

private-sector accreditation structure. A DoD-authorized Accreditation Body will authorize, accredit, and provide oversight of C3PAOs which in turn will conduct Level 2 certification assessments of actual and prospective DoD contractors and subcontractors. Defense contractors will directly contract with an authorized or accredited C3PAO to obtain a Level 2 (printed page 83175) certification assessment. The cost of Level 2 certification assessment activities is driven by multiple factors, including market forces that govern availability of C3PAOs and the size and complexity of the enterprise or enclave under assessment. The Government will perform Level 3 certification assessments. Government resource limitations may affect schedule availability. Reduces Duplicate or Respective Assessments of Our Industry Partners CMMC assessment results will be posted in SPRS, DoD's authoritative source for supplier and product performance information. Posting CMMC assessment results in SPRS precludes the need to validate CMMC implementation on a contract-by-contract basis. This enables DoD to identify whether the CMMC requirements have been met for relevant contractor information systems, avoids duplicative assessments, and eliminates the need for program level assessments, all of which decreases costs to both DoD and industry. Revised CMMC Program Implementation

(i) Attorneys hired solely to represent the contractor in any civil or criminal case in federal or State courts unless the disclosure is specifically authorized by the agency that has jurisdiction over the information. (ii) Any federal or state court except on specific instructions of the agency, which has jurisdiction over the information or the attorney representing the United States in the case. (8) Disclosure to the public. Contractors will not disclose classified information to the public. Contractors will not disclose unclassified information pertaining to a classified contract to the public without prior review and clearance as specified in the Contract Security Classification Specification, or equivalent, for the contract or as otherwise specified by the GCA. The procedures of this paragraph also apply to information pertaining to classified contracts intended for use in unclassified brochures, promotional sales literature, reports to stockholders, or similar material. (i) The contractor will: (A) Submit requests for approval through the activity specified in the GCA-provided classification guidance for the contract involved. (B) Include in each request the approximate date the contractor intends to release the information for public disclosure and identify the media to be used for the initial release. (C) Retain a copy of each approved request for release for a period of one inspection cycle for review by the CSA. (D) Clear all information developed subsequent to the initial approval through the appropriate office prior to public disclosure. (ii) Unless specifically prohibited by the GCA, the contractor does not need to request approval for disclosure of: (A) The fact that a contract has been received, including the subject of the contract or type of item in general terms (printed page 83344) provided the name or description of the subject is not classified. (B) The method or type of contract. (C) Total dollar amount of the contract unless that information equates to: (1) A level of effort in a sensitive research area. (2) Quantities of stocks of certain weapons and equipment that are classified. (D) Whether the contract will require the hiring or termination of employees. (E) Other information that from time-to-time may be authorized on a case-by-case basis in a specific agreement with the contractor. (F) Information previously officially approved for public disclosure. (iii) Information that has been declassified is not authorized for public disclosure. If the information is comingled with CUI, or qualifies as CUI once declassified, it will be marked and protected as CUI until it is decontrolled pursuant to 32 CFR part 2002 and reviewed for public release. If the information does not qualify as CUI, it will be protected in accordance with the basic safeguarding requirements in 48 CFR 52.204-21

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by organizations even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, organizations may wish to closely follow the development of these new publications by NIST. - [21] Premiere Election Solutions (2008, August 19). Product Advisory Notice . Accessed May 15, 2010 at <http://www.sos.state.oh.us/sos/upload/news/20081001c.pdf> - [22] Fink, R.A.; Sherman, A.T.; Carback, R.; , "TPM Meets DRE: Reducing the Trust Base for Electronic Voting Using Trusted Platform Modules," Information Forensics and Security, IEEE Transactions on , vol.4, no.4, pp.628-637, Dec. 2009. - [23] Ben Adida, Olivier de Marneffe, Olivier Pereira, and Jean-Jacques Quisquater. Electing a University President Using Open-Audit Voting: Analysis of Real-World Use of Helios, In D. Jefferson, J.L. Hall, T. Moran, editor(s), Electronic Voting Technology

Workshop/Workshop on Trustworthy Elections , Usenix, August 2009. - [24] Nathanael Paul, Andrew S. Tanenbaum, "The Design of a Trustworthy Voting System," Computer Security Applications Conference, Annual, pp. 507-517, 2009 Annual Computer Security Applications Conference, 2009. - [25] Common Criteria for Information Security Evaluation. Part 3: Security assurance components. Version 3.1, Rev. 3, July 2009. - [26] Patrick Peterson, Henry Stern. "Botnets Gone Wild! Captured, Observed, Unraveled, Exterminated." Presented at RSA 2010, San Francisco, CA, March 1-5, 2010. - [27] Testimony of Bob Carey, Director of FVAP. (2010) EAC Public Meeting, Dec. 3 2009.

CMMC Level 3 scoring does not utilize varying values like the scoring for CMMC Level 2. All CMMC Level 3 security requirements use a value of one (1) point for each security requirement. As a result, the maximum score achievable for a Level 3 certification assessment is equivalent to the total number of the selected subset of NIST SP 800-172 Feb2021 security requirements for CMMC Level 3, see § 170.14(c)(4). The maximum score is reduced by one (1) point for each security requirement NOT MET. The CMMC Level 3 scoring methodology reflects the fact that all CMMC Level 2 security requirements must already be MET (for the Level 3 CMMC Assessment Scope). A maximum score on the Level 2 certification assessment is required to be eligible to initiate a Level 3 certification assessment. The Level 3 certification assessment score is equal to the number of CMMC Level 3 security requirements that are assessed as MET. Appendix A to Part 170-Guidance Guidance documents include: (a) ·CMMC Model Overview· available at <https://DoDcio.defense.gov/CMMC/> . (b) ·CMMC Assessment Guide·Level 1· available at <https://DoDcio.defense.gov/CMMC/> . (c) ·CMMC Assessment Guide·Level 2· available at <https://DoDcio.defense.gov/CMMC/> . (d) ·CMMC Assessment Guide·Level 3· available at <https://DoDcio.defense.gov/CMMC/> . (e) ·CMMC Scoping Guide·Level 1· available at <https://DoDcio.defense.gov/CMMC/> . (f) ·CMMC Scoping Guide·Level 2· available at <https://DoDcio.defense.gov/CMMC/> . (g) ·CMMC Scoping Guide·Level 3· available at <https://DoDcio.defense.gov/CMMC/> . (h) ·CMMC Hashing Guide· available at <https://DoDcio.defense.gov/CMMC/> . Dated: September 30, 2024. Patricia L. Toppings, OSD Federal Register Liaison Officer, Department of Defense. Footnotes 1. www.federalregister.gov/citation/75-FR-68675 (November 4, 2010). Back to Citation 2. www.federalregister.gov/citation/75-FR-707 (December 29, 2009). Back to Citation 3. www.govinfo.gov/link/uscode/42/2011 , et seq. Back to Citation 4. www.federalregister.gov/documents/2020/09/29/2020-21123/defense-federal-acquisition-regulation-supplement-assessing-contractor-implementation-of . Back to Citation 5. www.federalregister.gov/documents/2024/08/15/2024-18110/defense-federal-acquisition-regulation-supplement-assessing-contractor-implementation-of . Back to Citation 6. www.sprs.csd.disa.mil/ under OMB control number 0750-0004. Back to Citation 7. www.acquisition.gov/dfars/252.204-7012-safeguarding-covered-defense-information-and-cyber-incident-reporting . Back to Citation 8. www.acquisition.gov/dfars/252.204-7020-nist-sp-800-171dod-assessment-requirements . Back to Citation 9. ·Required since November 2016, NIST SP 800-171 R2 security requirement 3.12.4 states organizations must ·develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems.· Back to Citation 10.

The Department proposes that the period of inactivity be both predetermined and reasonable and appropriate. When determining the length of the period of inactivity, a regulated entity should consider the access privileges of a given user or technology asset, the system(s) being accessed, the environment in which the system access occurs, and other appropriate factors in determining a reasonable and appropriate time of inactivity before session termination. For example, in an emergency setting, a user may not have time to manually log out of a system. User identities with administrative and other high-level access that present a greater risk to the confidentiality, integrity, and availability of ePHI should have appropriately shorter periods of inactivity because of the increased risk. While many applications have configuration settings for automatic logoff, [708] a regulated entity must determine whether the default automatic logoff is reasonable and appropriate and make modifications if it is not. For example, the adoption of health IT that is certified through the ONC Health IT Certification Program as having the technical capability to automatically stop a user's access to health information after inactivity for a predetermined period and require a user to re-enter their credentials to resume or regain access may contribute to a regulated entity's compliance with the proposed implementation specification for automatic logoff, should the proposal be finalized. [709] Additionally, we propose to add an implementation specification for log-in attempts at proposed 45 CFR 164.312(a)(2)(v) . The proposal would require

a regulated entity to deploy technical controls that disable or suspend the access of a user or technology asset to relevant electronic information systems after a certain number of unsuccessful authentication attempts. Although incorrectly keying in a known password by the intended user may occur infrequently, a repeated and persistent failure is a strong indication of an attempt at unauthorized access. For example, brute force attacks are attempts to gain unauthorized access by guessing the password many times in a row. [710] Technical controls that limit the number of incorrect log-in attempts by disabling or suspending the access of a user or technology asset to relevant electronic information systems are appropriate to address unsuccessful login attempts. [711] The proposal would require a regulated entity to determine the number of unsuccessful authentication attempts that would trigger disabling or suspending access to relevant electronic information system. The number should (printed page 967)

Most surface courier services may carry food items as an incidental part of their business and will incur learning costs as a result of this rule. However, only a small fraction will carry food items as a significant part of their business and will incur additional records maintenance and records redesign costs. We estimate that 10 percent of surface couriers services will ve more than an incidental portion of their business transporting food items and will incur records redesign and additional maintenance costs in addition to learning costs. This is consistent with the fraction of restaurants that report retail sales as a secondary activity of their establishment (Ref. 29). The resulting estimated number of surface transporters of low-value packages of food items that would incur additional records maintenance and records redesign costs is 7,097 facilities. (Comment 206) Several comments suggest that transportation carriers have only a limited knowledge of the contents of the packages that they carry and should not be held liable for much of the information. These comments suggest that transporters have detailed information on sources and recipients of the products that they carry but do not have the capacity to track other details of the contents of the packages, such as lot codes and other details. For example, one comment states that air carriers typically rely on the shippers for information, and shipments may not be identified as containing food. Others comment that because carriers lack knowledge of the contents of packages, the default records retention times for all shipments will be the longer required time of 2 years, even if the contents are perishable products. The comments state that this 2-year default retention time will only add to the records retention burden already faced by many trucking firms.

cluding Nathan Aileo, Ujwala Arikatla, Mark Bunn, Jim Foti, John Groenveld, Susan Hansche, Blair Heiserman, Frank Husson, Mike Ko, Alan McClelland, Susan Pagan, David Waltermire, and Kimberly Watson . The authors also gratefully acknowledge and appreciate the comments and contributions made by government agencies, private organizations, and individuals in providing direction and assistance in the development of this document.

Several comments addressed references to documents outside the rule, or those that are incorporated by reference. One commenter asked how the DoD will recognize when revisions to documents incorporated by reference cause them to be misaligned requirements identified in this rule. Other comments requested that additional documents be incorporated by reference, such as DoD Instructions on CUI and the DISA Cloud Security Technical Reference Architecture. Some commenters complained that the page count of the rule and documents incorporated by reference was too high and asked whether contractors are expected to read them all. Two commenters objected to certain terms in the definitions section pointing to other documents as the source of the (printed page 83160) definition. One further suggested that such definitions be revised to simply point to the URL of the source definition. Some comments recommended moving content from the new 32 CFR part 170 CMMC Program rule to the CMMC supplemental documents or changing citations to reference them rather than the NIST documents that are incorporated by reference. Another asked why the scoring methodology was incorporated into the rule, rather than incorporated by reference. One comment questioned whether the supplemental documents are truly optional, rather than required for compliance with CMMC program requirements. One comment stated a public comment period should be required for all supplemental guidance prior to final publication. One commenter asked what precipitated implementation of the CFR, which the DoD interpreted as a question about codification of the CMMC program in the CFR. One commenter asked whether the rulemaking process had afforded a certain group the opportunity to coordinate or comment on the rule. Another referenced the separate 48 CFR part 204 CMMC Acquisition rulemaking effort needed to implement the content of this rule and urged the DoD to consider public comments of both rules prior to their publication as final. One comment specifically suggested the CMMC program be implemented Government-wide. One commenter simply

submitted a copy of a CMMC-related article from the February 2024 issue of National Defense Magazine and quoted or extracted from it rather than providing any specific comment or question. Response: The process for creating Federal regulations generally has three main phases: initiating rulemaking actions, developing proposed rules, and developing final rules. A proposed rule is published for public comment prior to developing the final rule. A final rule must identify its effective date and be published 60 days prior to that date. The structure and formatting requirements for proposed and final rules and the process for submitting public comments are prescribed by the Office of the Federal Register and OMB, respectively, and are outside of DoD's control.

Establish and implement written policies and procedures that govern the receipt and removal of technology assets that maintain electronic protected health information into and out of a facility, and the movement of these assets within the facility. (2) Implementation specifications ·(i) Disposal. Establish and implement written policies and procedures for disposal of electronic protected health information and the technology assets on which it is maintained based on current standards for disposing of such technology assets. (ii) Media sanitization. Establish and implement written procedures for removal of electronic protected health information from electronic media such that the electronic protected health information cannot be recovered, based on current standards for sanitizing electronic media before the media are made available for re-use. (iii) Maintenance. Review and test the written policies and procedures required by paragraphs (d)(2)(i) and (ii) (printed page 1017) of this section at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. §·164.312 Technical safeguards. Each covered entity or business associate must, in accordance with §§·164.306 and 164.316, implement all of the following technical safeguards, including technical controls, to protect the confidentiality, integrity, and availability of all electronic protected health information that it creates, receives, maintains, or transmits: (a) Standard: Access control ·(1) General. Deploy technical controls in relevant electronic information systems to allow access only to users and technology assets that have been granted access rights. (2) Implementation specifications ·(i) Unique identification. Assign a unique name, number, and/or other identifier for tracking each user and technology asset in the covered entity or business associate's relevant electronic information systems. (ii) Administrative and increased access privileges. Separate user identities from identities used for administrative and other increased access privileges. (iii) Emergency access procedure. Establish (and implement as needed) written and technical procedures for obtaining necessary electronic protected health information during an emergency. (iv) Automatic logoff. Deploy technical controls that terminate an electronic session after a predetermined time of inactivity that is reasonable and appropriate. (v) Log-in attempts. Deploy technical controls that disable or suspend the access of a user or technology asset to relevant electronic information systems after a reasonable and appropriate predetermined number of unsuccessful authentication attempts. (vi) Network segmentation. Deploy technical controls to ensure that the covered entity's or business associate's relevant electronic information systems are segmented in a reasonable and appropriate manner. (vii) Data controls.

(D) From subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (E) From subsections (e)(4)(G) and (H) because this system of records is exempt from individual access pursuant to subsections (j)(2) of the Privacy Act of 1974. (F) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (G) From subsection (e)(5) because in the collection of information for law enforcement purposes it is impossible to determine in advance what information is accurate, relevant, timely, and complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light and the accuracy of such information can only be determined in a court of law. The restrictions of subsection (e)(5) would restrict the ability of trained investigators and intelligence analysts to exercise their judgment reporting on investigations and impede the development of intelligence necessary for effective law enforcement. (H) From subsection (e)(8) because the individual notice requirements of subsection (e)(8) could present a serious impediment to law enforcement as this could interfere with the ability to issue search authorizations and could reveal investigative techniques and procedures. (I) From subsection (f) because this system of records has been exempted from the access provisions of subsection (d). (J) From subsection (g)

because this system of records compiled for law enforcement purposes and has been exempted from the access provisions of subsections (d) and (f). (6) System identifier and name. F090 AF IG B, Inspector General Records. (i) Exemption. (A) Parts of this system of records may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principle function any activity pertaining to the enforcement of criminal laws. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(j)(2) from the following subsections of 5 U.S.C. 552a(c)(3), (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (H), and (I), (e)(5), (e)(8), (f), and (g). (B) Investigative material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2)

2 A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information. (44 U.S.C., Sec. 3502) Mission/Business Owner - The Mission/Business Owner is a high-level official ultimately responsible for the procurement, development, integration, modification, operation, and maintenance of an information system. The Mission/Business Owner may delegate execution of their responsibilities to Program Managers who work closely with the Authorizing Official (AO), Senior Information Security Officer (SISO), Information Systems Security Officer (ISSO), and the CO to ensure that supply chain risk mitigation strategies are selected, implemented, and operating as intended. The Mission/Business Owner is ultimately responsible for ensuring collaboration with various functional experts to identify and implement ICT supply chain practices that are sufficient to mitigate risks. The functional areas that may be involved include: systems engineering, system security engineering, facilities management including physical security, requirements engineering, quality assurance, reliability, compliance, manufacturing, assembly, testing, acceptance, maintenance, system and network administration, shipping and receiving, packaging and labeling, delivery, inventory management, finance, disposal, and waste management.

CMMC Level 5 does not exist under CMMC 2.0. The current framework (32 CFR Part 170) defines three levels: Level 1, Level 2, and Level 3. The original CMMC 1.0 model had five levels, but the 2.0 revision consolidated them into three. If you need the highest level of CMMC compliance, that is Level 3, which requires implementation of NIST SP 800-172 enhanced security requirements and a government-led assessment by DIBCAC.

(2) Any (a)(2) record relied on, used, or cited as precedent by an agency against a party that is issued, promulgated, or adopted after July 4, 1967, must be indexed and either made available or published, or the individual must have actual and timely notice of the contents of such records. Such records issued, promulgated, or adopted before July 4, 1967, need not be indexed, but must be made available upon request if not exempted under § 286.13. (3) Each DoD Component shall promptly publish quarterly or more frequently, and distribute by sale or otherwise, copies of each index of (a)(2) records or supplements thereto, unless it publishes in the Federal Register an order containing a determination that publication is unnecessary and impracticable. A copy of each index or supplement not published shall be provided to a requester at a cost not to exceed the direct cost of duplication as set forth in § 286.24 of this part. (4) Each index of (a)(2) records or supplement thereto shall be arranged by topical or descriptive words, rather than by case name or numbering system, so that the public can readily locate material. Case name and numbering arrangements may also be included for DoD Component convenience. (5) Listing of electronically available (a)(2) documents in a Component's electronic reading room satisfies this requirement. (b) Major information systems. 5 U.S.C. 552(g)(1) and (2) require agencies to make publicly available an index of all major information systems and a description of major information and record locator systems. This requirement will be met for the entire Department of Defense by DFOIPO on its Web site. § 286.10 (a)(1)-records. (a) Although (a)(1) records are not required to be made available in response to FOIA requests or in FOIA reading rooms, they shall be made available when feasible. Examples of (a)(1) records are descriptions of an agency's central and field organization and, to the extent they affect the public, rules of procedures; descriptions of forms available; instructions as to the scope and contents of papers, reports, or examinations; and any amendments, revisions, or reports of the aforementioned records. (b) In accordance with 5 U.S.C. 552(a)(1), each DoD Component shall disclose, through publication in the Federal Register, information describing its organization, functions, procedures, substantive rules, and statements of general policy. Any available index of DoD Component records published in the Federal Register, in addition to (a)(1) records, shall be made available to the public in DoD Component FOIA reading

rooms and electronically. Subpart C-Exemptions § 286.13 General provisions. (a) Records that meet FOIA exemption criteria may be withheld from public disclosure and need not be published in the Federal Register, made available in a reading room, or provided in response to a FOIA request.

3.2.1 | Inventory and Valuation of Assets... 3.2.1 Inventory and Valuation of Assets Since cybersecurity risk reflects, in part, the effect of uncertainty on digital components that support enterprise objectives, practitioners identify the assets that are necessary to achieve those objectives. 3.2.1 through 3.

3. Where Federal Agencies having the power to subpoena other Federal Agencies' records, such as the Internal Revenue Service, issue a subpoena to HHS for records in this system of records, HHS will make such records available, provided however, that in each case, HHS determines that such disclosure is compatible with the purpose for which the records were collected. 4. A record from this system may be disclosed to entities as provided for in the Debt Collection Improvement Act of 1996 (Pub. L. 104-134). 5. A record may be disclosed to banks enrolled in the Treasury Credit Card Network to collect a payment or debt when the person has given his/her credit card number for this purpose. 6. UFS submitter data (name, address, DUNS number) may be provided to Dun and Bradstreet for validation for the purpose of maintaining database integrity. 7. Disclosure may be made to the Department of Justice (DOJ) when: (a) The Agency or any component thereof; (b) any employee of the Agency in his or her official capacity; (c) any employee of the Agency in his or her individual capacity where the DOJ has agreed to represent the employee; or (d) the U.S. Government is a party to litigation or has an interest in such litigation, and by careful review, the Agency determines that the records are both relevant and necessary to the litigation and the use of such records by the DOJ is therefore deemed by the Agency to be for a purpose that is compatible with the purpose for which the Agency collected the records. 8. Disclosure may be made to a court or other tribunal, when: (a) The Agency or any component thereof; (b) any employee of the Agency in his or her official capacity; (c) any employee of the Agency in his or her individual capacity where the DOJ has agreed to represent the employee; or (d) the U.S. Government is a party to the proceeding or has an interest in such proceeding, and by careful review, the Agency determines that the records are both relevant and necessary to the proceeding and the use of such records is therefore deemed by the Agency to be for a purpose that is compatible with the purpose for which the Agency collected the records. 9. Disclosure may be made to contractors and other individuals who perform services for the Agency related to this system of records, and who need access to the records in order to perform such services. Recipients shall be required to comply with the requirements of the Privacy Act of 1974, as amended, 5 U.S.C. 552a . 10. Disclosure may be made to NARA and/or the General Services Administration for the purpose of records management inspections conducted under authority of 44 U.S.C. 2904 and 2906 .

In accordance with the authority in DoD Directive (DoDD) 5143.01, the purpose of the rule is to implement policy, assign responsibilities, establish requirements and provide procedures, consistent with E.O. 12829 , DoD Instruction (DoDI) 5220.22, and E.O. 10865 , 'Safeguarding Classified Information within Industry,' for the protection of classified information that is disclosed to, or developed by contractors. This rule provides NISP policy to the Components and establishes procedures concerning the initial FCL eligibility of U.S. companies that may be subject to FOCI or continued FCL eligibility for contractors subject to FOCI; provides criteria for determining whether contractors are under FOCI; prescribes responsibilities in FOCI matters; and outlines security measures that may be considered to negate or mitigate the effects of FOCI to an acceptable level. This rule does not levy requirements on U.S. contractors. Depending upon the nature and extent of FOCI, DoD mitigates FOCI by putting into place mechanisms such as a voting trust agreement (VTA), proxy agreement (PA), special security agreement (SSA) or security control agreement (SCA). These arrangements require trustees, proxy holders or outside directors to oversee and provide business management of the U.S. contractor. For calendar year (CY) 11, five contractors cleared by DoD were subject to a SCA, of which three required access to SECRET information and two required access to TOP SECRET information. The average number of outside directors for a SCA is two. For CY11, 16 contractors were subject to a SSA, of which 12 required access to SECRET information and four required access to TS information. The average number of outside directors for a SSA is three. In CY 11, there were no VTAs and nine PAs that required access to TS information. The average number of proxy holders for a PA is three. The proxy holders, voting trustees, or outside directors must be eligible for access at the level of the FCL. CY 11 total estimated costs for personnel security investigations of trustees, proxy holders and outside director are as follows: (1) The unit cost

for a SECRET clearance (National Agency Check with Law and Credit NACLC) is \$228. 3 SCA × 2 outside directors × \$228/NACLC = \$1,368 12 SSA × 3 outside directors × \$4005/NACLC = \$8,208 (2) The unit cost for a TS (Single Scope Background Investigation-SSBI) is \$4,005 2 SCAs × 3 outside directors × \$4,005 = \$16,020 4 SSAs × 3 outside directors × \$4,005 = \$48,060 9 PAs × 3 proxy holders × \$4,005 = \$108,135 Therefore, the total estimated investigation cost for outside directors and proxy holders under SCAs, SSAs and PAs for CY 11 is \$181,791. These costs are government costs and not levied on contractors. FOCI measures provide protection from unauthorized transfer of classified information to foreign interests, thus saving billions of dollars.

One respondent inquired whether paragraph (a) of the clause at DFARS 252.232-7002, Progress Payments for Foreign Military Sales Acquisitions, requires separate submission of foreign military sales (FMS) progress payment requests combined with U.S. sales progress payment requests, or rather that the clause requires submission of FMS progress payment requests separate from U.S. ones. Response: The intent is for FMS progress payment requests to be submitted separately from U.S. sales progress payment requests. The language in the clause at DFARS 252.232-7002 has been clarified in the final rule. 3. Prescription for the Clause at DFARS 252.232-70XX Comment: One respondent inquired whether the prescription for the clause at DFARS 252.232-70XX, Progress Payments-Multiple Lots, should explicitly limit application of the clause to fixed price contracts. Response: In accordance with Federal Acquisition Regulation 32.500(a), only fixed-price contracts may provide for progress payments. The prescription limits application of the clause at DFARS 252.232-7018 to contracts that provide for progress payments. DoD therefore declines the suggested change as unnecessary. 4. References to Subcontractor Progress Payments Comment: One respondent recommends changing the term subcontractor progress payments to subcontract financing in the clauses at DFARS 252.232-7002(d) and 252.232-70XX(b)(4) to better align with relevant language in the Federal Acquisition Regulation. Response: In the final rule, the term subcontractor progress payments is changed to subcontract financing in the clauses at DFARS 252.232-7002, paragraph (d), and 252.232-7018, paragraph (b)(4). III. Applicability to Contracts at or Below the Simplified Acquisition Threshold (SAT) and for Commercial Services, and for Commercial Products, Including Commercially Available Off-the-Shelf (COTS) Items This rule clarifies payment instructions for certain contracts based on the type of item acquired and the type of payment by amending DFARS 252.204-7006, Billing Instructions-Cost Vouchers, and 252.232-7002, Progress Payments for Foreign Military Sales Acquisitions. Application of these clauses to contracts at or below the SAT and to commercial services, commercial products, and COTS items is unchanged. This final rule adds a new clause at 252.232-7018, Progress Payments-Multiple Lots. DoD will apply this clause to solicitations and contracts at or below the SAT and will not apply the clause to commercial services or commercial products, including COTS items. IV. Expected Impact of the Rule

DFARS 252.204-7012 (Safeguarding Covered Defense Information and Cyber Incident Reporting) Core CUI protection clause requiring NIST SP 800-171 implementation, cyber incident reporting within 72 hours, and preservation of evidence. Flow-down requirements: DFARS 252.204-7012 includes flow-down provisions requiring prime contractors to include the clause in subcontracts where CUI will be processed, stored, or transmitted. Subcontractors must meet the same security requirements as the prime.

(Response) FDA is requiring an adequate description of the type of food received or released to include brand name where applicable and specific variety where applicable (e.g., brand x cheddar cheese, not just cheese; or romaine lettuce, not just lettuce). FDA agrees that specific variety may not apply in all cases, but should be provided where it applies because it will help narrow the investigation and help FDA identify the immediate previous sources and immediate subsequent recipients of food to address credible threats of serious adverse health consequences or death to humans or animals. (Comment 105) Some comments recommend that the agency allow the use of company specific codes or an existing abbreviation system. One comment states that commercial documents often incorporate code numbers and abbreviations that identify the food products very specifically. The comments add that, as long as these codes and abbreviations can be deciphered readily for FDA in the event of an agency request for records, the product descriptions should be considered sufficient in their present form. (Response) As discussed in response to comment 103 of this document, in keeping with FDA's intention to ensure these regulations are not unnecessarily burdensome, FDA agrees that covered persons may use existing abbreviation or code systems that identify the food very specifically, provided the abbreviations or codes can be readily deciphered at the time the records are made available to FDA following an agency request. (Comment 106) Some comments who

represent warehouses state that they rely on the customer's description of the product as the food comes to them in shrink-wrapped pallets and cartons and the warehouse is not permitted to open the packaging. (Response) It is not clear from the comment what the 'customer's description' entails; however, FDA is requiring an adequate description of the type of food to be able to narrow the scope of the implicated food in the event of a public health emergency. For this reason, each entity within the chain of distribution of the food must establish and maintain records that adequately describe the type of food received and released so that FDA can identify the immediate previous sources and immediate subsequent recipients of food to address credible threats of serious adverse consequences or death to humans or animals. It is the responsibility of the covered entity to revise its recordkeeping system so that it establishes and maintains records containing all required information. In the previous example, the warehouse may need to require its customers to provide it with a more detailed description when food is delivered or released than it currently receives. 5. Date Food Received or Released (Comment 107) One comment agrees with the proposed requirement. Another stated that the term 'released' is ambiguous in a commercial environment and asked for clarification.

3.4.2 REPORT ON SECURITY CONTROL ASSESSMENTS Organizations report on assessments of all implemented security controls for effectiveness in accordance with organizational requirements.

as 'basic and applied research in science and engineering, the results of which ordinarily are published and shared broadly within the scientific community, as distinguished from proprietary research and from industrial development, design, production, and product utilization, the results of which ordinarily are restricted for proprietary or national security reasons.' CMMC Program requirements apply only to defense contractors and subcontractors who handle FCI and CUI on an information system associated with a contract effort or any information system that provides security protections for such systems, or information systems not logically or physically isolated from all such systems. Fundamental research that is 'shared broadly within the scientific community' is not, by definition, FCI or CUI; however, other research-related information that is provided to or handled by contractors as part of contract performance may be FCI or CUI, thus may trigger application of CMMC Level requirements. If DoD determines the information handled by contractors pursuant to the fundamental research contract activities is or will become FCI or CUI, the information would be required to be processed, stored, or transmitted on an information system compliant with the appropriate CMMC Level. 6. International Foreign DIB Partners/Non-U.S. Contractors Comment: Multiple commenters asked if international subcontractors of a U.S. prime will require CMMC certification. Commenters also asked if there is a strategy for legally implementing CMMC requirements beyond the U.S. DIB, and if an enterprise-level resolution has been developed to address foreign DIB sovereignty. One commenter suggested that some foreign governments have issued guidance to their local companies directing them not to accept CMMC flow down requirements. One commenter expressed concern regarding the impact of CMMC to existing bilateral/multilateral security agreements. Another commenter asked if the foreign DIB will be authorized to evaluate U.S. DIB and vice versa. One non-U.S. commenter suggested using the existing Facility Security Clearance process to ensure a company is compliant with CMMC in accordance with national legislation. Response: Contractors are required to comply with all terms and conditions of the contract, to include terms and conditions relating to cybersecurity protections and assessments. In addition, offerors will be required to comply with the pre-award CMMC requirement. This holds true when a contract clause is flowed down to subcontractors. The Facility Security Clearance process does not apply to unclassified information systems owned by, or operated on behalf of, a non-federal entity (e.g., contractors), and, therefore, does not apply to systems/networks that will be subject to CMMC requirements. This rule makes no distinction about which C3PAOs may assess which companies seeking certification. For more details on C3PAO requirements, see §170.9. 7. CUI and FCI

1. Minimize potential impacts to customer satisfaction, brand reputation, and shareholder value. 2. Minimize impact to cost, performance, timing, and availability of goods. 3. Ensure consistency across IT/OT platforms. 4. Meet regulatory responsibilities. 5. Ensure integrity and continuity of accounting processes (e.g., accounts receivable and accounts payable). 6. Mitigate lack of control of documents when sent to the supplier (e.g., IP theft). 7. Minimize impact to product quality. 8. Ensure visibility into how third-party Operations & Maintenance sites are built and used (i.e., no standard build out). This section covers how the organizations determine criticality of a third-party product, component, or service, as well as the type of requirements they put in contracts and service agreements to cover security aspects such as quality, integrity, and confidentiality. 1. Contractual terms and conditions include insurance, access requirements, and background checks. 2. Suppliers are contractually obligated to disclose component vulnerabilities, data loss, and security incidents. 3. The quality and interruption of supply are specifically mentioned in service agreements, though security is not called out. 4. Contractual terms and conditions include a specific section on information security requirements as well as consequences if there is a failure to comply with the requirements for security, quality, and integrity. 5. Contractual requirements include regular site visits, informal touchpoints, and supplier meetings.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. All organizations rely on acquiring products and services, and most organizations also supply products and services to other organizations. Cyber Supply Chain Risk Management is an organization-wide function that encompasses multiple activities throughout the system development life cycle. The audience for this publication is any organization-regardless of its size, scope, or complexity-that wants to manage the cybersecurity risks stemming from extended supply chains and supply ecosystems.

printed page 83164) undergoing an assessment and the CMMC Status that may result from that activity. An OSA undergoes one of the following: Level 1 self-assessment; Level 2 self-assessment; Level 2 certification assessment; or Level 3 certification assessment. The result of that assessment activity is either failure to meet minimum requirements or one of the following CMMC Statuses: Final Level 1 (Self); Conditional Level 2 (Self); Final Level 2 (Self); Conditional Level 2 (C3PAO); Final Level 2 (C3PAO); Conditional Level 3 (DIBCAC); or Final Level 3 (DIBCAC). The official DoD acronym for CCA is ·CMMC Certified Assessor·, as addressed in § 170.4. All CMMC terms and definitions provided in this 32 CFR part 170 CMMC Program rule are codified and therefore take precedence over definitions and acronym usage from the CMMC website or other sources. To avoid confusion in the ecosystem with the term ·practitioner·, the DoD modified the definition in § 170.4 to replace the word ·practitioners· with ·professionals·. While ·must· is a more commonly used term than ·shall·, both terms impose a requirement as defined in FAR 2.101 Definitions. 33. Rule Text Modifications a. Changes to the Preamble Comment: One commenter recommended that the supplemental Assessment Guides be consolidated with and cross referenced to requirements for the CMMC Levels in the same document. Eighty-three comments requested changes to the preamble section of the rule text. Of those, 17 were incorporated and are summarized below. Writing Style: Multiple commenters wanted shorter, simpler, and more focused wording starting with changes to the first sentence in the

Summary section. Word Choices: In the CMMC 2.0 Overview as Proposed by this Rule section several comments objected to the description of FAR clause 52.204-21 requirements as 'elementary' or 'basic'. One comment asserted that 'may' is not the correct verb for 'Defense contracts . . . may include applicable requirements . . .'. One comment suggested the preamble sentence 'Once CMMC is implemented, the required CMMC level for contractors will be specified in the solicitation,' be revised to use wording that is more consistent with other parts of the preamble and rule text. One commenter proposed edits to remove passive voice from a sentence in the preamble description of Key Changes Incorporated in the Revised CMMC Program. One commenter requested a change to reference the relevant DFARS clause 252.204-7012, rather than the DFARS subpart 204.73. Clarifications:

3.2.6 FINALIZE ASSESSMENT PLAN AND OBTAIN APPROVAL TO EXECUTE PLAN After selecting the assessment procedures (including developing necessary procedures not contained in the SP 800-53A catalog of procedures), tailoring the procedures for system/platform-specific and organization-specific conditions, optimizing the procedures for efficiency, and addressing the potential for unexpected events that may impact the assessment, the assessment plan is finalized and the schedule is established, including key milestones for the assessment process.

CIS Safeguard 17.1 · Designate Personnel to Manage Incident Handling Designate one key person, and at least one backup, who will manage the enterprise's incident handling process. Management personnel are responsible for the coordination and documentation of incident response and recovery efforts and can consist of employees internal to the enterprise, third-party vendors, or a hybrid approach. If using a third-party vendor, designate at least one person internal to the enterprise to oversee any third-party work. Review annually, or when significant enterprise changes occur that could impact this Safeguard. Implementation Groups: 1,2,3 Asset Type: N/A Security Function: respond Parent Control: Incident Response Management

During Fiscal Year 2019 (FY 2019), from October 1, 2018 through September 30, 2019, the NIST Information Technology Laboratory (ITL) Cybersecurity and Privacy Program successfully responded to numerous challenges and opportunities in security and privacy. This annual report highlights the FY 2019 research agenda and activities for the ITL Cybersecurity and Privacy Program, including: the ongoing participation and development of international standards; the enhancement of privacy and security risk management models, including those for the protection of controlled unclassified information (CUI), systems engineering and cyber resiliency, supply chains, and mobile technologies; the continued advancement of cryptographic technologies, including updates to Federal Information Processing Standard (FIPS) Publication 140-3, Security Requirements for Cryptographic Modules, and preparation for post-quantum cryptographic methods; and improved infrastructure protection in areas such as zero trust architectures and advanced networking security. NIST maintained a strong focus on supporting small and medium-sized businesses (SMBs), including updates to the Small Business Cybersecurity Corner website to make resources easier to find and use, and drawing on contributed cybersecurity resources and feedback received from federal partners and the public. initial alignment with the constructs in the NIST Cybersecurity Framework, the integration of privacy risk management processes, an alignment with system life-cycle security engineering processes, and the incorporation of supply chain risk management processes. ## Cyber Supply Chain Risk Management (C-SCRM)

is classified or unclassified information concerning the design, arrangement, development, manufacture, testing, operation, administration, training, maintenance, and repair of the propulsion plants of naval nuclear-powered ships and prototypes, including the associated shipboard and shore-based nuclear support facilities. Non-DoD executive branch agencies means the non-DoD agencies that have entered into agreements with DoD to receive NISP industrial security services from DoD. A list of these agencies is on the Defense Counterintelligence and Security Agency website at <https://www.dcsa.mil>. Non-Federal information system is defined in 32 CFR part 2002. NRTL means a private sector organizations recognized by the Occupational Safety and Health Administration to perform certification for certain products to ensure that they meet the requirements of both the construction and general industry Occupational Safety and Health Administration electrical standards. Each NRTL is recognized for a specific scope of test standards. NSI means information that has been determined pursuant to E.O. 13526 or predecessor order to require protection against unauthorized disclosure and marked to indicate its classified status. NTIB means the industrial bases of the United States and Australia, Canada, and the United Kingdom. NTIB entity means a person that is a subsidiary located in the United States for which the ultimate parent entity and

any intermediate parent entities of such subsidiary are located in a country that is part of the national technology and industrial base (as defined in section 2500 of title 10, United States Code); and that is subject to the foreign ownership, control, or influence requirements of the National Industrial Security Program. Nuclear weapon data means Restricted Data or Formerly Restricted Data concerning the design, manufacture, or utilization (including theory, development, storage, characteristics, performance and effects) of nuclear explosives, nuclear weapons or nuclear weapon components, including information incorporated in or related to nuclear explosive devices. Nuclear weapon data is matter in any combination of documents or material, regardless of physical form or characteristics. OCA means an individual authorized in writing, either by the President, the Vice President, or by agency heads or other officials designated by the President, to classify information in the first instance. Original classification means an initial determination that information requires, in the interest of national security, protection against unauthorized disclosure. Only USG officials who have been designated in writing may apply an original classification to information. Parent means an entity that owns at least a majority of another entity's voting securities. PCL

One commenter recommended mandating DIB use of the DoD CIO's DIB CS Program or other DoD cybersecurity related services as alternatives to the CMMC program. That comment suggested reassigning Government personnel to provide training for all assessors, to reduce training cost and ensure enough assessors to meet demand. Another commenter made similar recommendations about CISA cybersecurity service offerings. Response: Many comments included lengthy proposals for alternate approaches to the CMMC program which would alleviate specific concerns with aspects of CMMC program requirements. In some cases, the suggestions were based on a misreading of the rule's content. The DoD has addressed some valid concerns via rule revisions that differ from commenter recommendations. The DoD notes with interest one commenter's reference to initiatives described in a report to Congress about the breadth of cybersecurity related initiatives within the Department. While the CMMC is an important initiative, it is by no means the Department's only effort to improve DIB cybersecurity. The CMMC Program addresses adequate safeguarding of contractor owned information systems which process, store, or transmit FCI or CUI. Other DoD initiatives related to secure cloud or software development environments are beyond the scope of the CMMC Program. The DoD did not adopt suggested alternatives, such as policy-based solutions that lack a rigorous assessment component. The DoD determined that sharing CUI only through DoD-hosted secure platforms, in lieu of implementing the CMMC Program, was not a scalable or cost-effective solution. Although the DoD expanded the availability of resources through the DIB Collaborative Information Sharing Environment (DCISE) program, the DoD also declines to rely only on training in lieu of assessment. The purpose of CMMC is to require defense contractors and subcontractors to undergo an assessment to verify the implementation of prescribed cybersecurity standards. The security requirements are already specified in existing regulations (32 CFR part 2002 , DFARS clause 252.204-7012, and FAR clause 52.204-21).

(A) Are authorized to disclose classified information to a cleared subcontractor with the appropriate entity eligibility determination (also known as a facility security clearance) and need to know when access to classified information is necessary for the performance of tasks or services essential to the fulfillment of a prime contract or a subcontract. (B) Will convey appropriate classification guidance for the classified information to be disclosed with the subcontract in accordance with §.117.13. (ii) The CSA must have: (A) Made a determination of eligibility for access to classified information for the subcontractor, at the same level, or higher, than the classified information to be disclosed, to allow for such disclosures. (B) Approved storage capability for classified material at the subcontractor location if a physical transfer of classified material occurs. (3) Disclosure between parent and subsidiaries: (i) Contractors: (A) Are authorized to disclose classified information between parent and subsidiary entities with the appropriate entity eligibility determination (also known as a facility security clearance) and need to know when access to classified information is necessary for the performance of tasks or services essential to the fulfillment of a prime or subcontract. (B) Will convey appropriate classification guidance with the agreement or procurement action that necessitates the disclosure. (ii) The CSA must have: (A) Made a determination of eligibility for access to classified information for both the parent and subsidiary, at the same level, or higher, than the classified information to be disclosed, to allow for such disclosures. (B) Approved storage capability for classified material at the parent and the subsidiary if a physical transfer of classified material occurs. (4) Disclosure to federal agencies. Contractors will not disclose classified information

received or generated under a contract from one agency to any other federal agency unless specifically authorized by the agency that has classification jurisdiction over the information. (5) Disclosure of classified information to foreign persons. Contractors will not disclose classified information to foreign persons unless specified by the contract and release of the information is authorized in writing by the government agency having classification jurisdiction over the information involved, i.e. the DOE for RD and FRD (also see §.117.23), the NSA for COMSEC, the DNI for SCI, and all other executive branch departments and agencies for classified information under their respective jurisdictions. (6) Disclosure to other contractors. Contractors will not disclose classified information to another contractor except in furtherance of a contract, subcontract, or other GCA purpose without the authorization of the GCA, if such authorization is required by contract. (7) Disclosure of classified information in connection with litigation. Contractors will not disclose classified information to:

Delete entry and replace with ·Records maintained by Headquarters and field Offices of Counsel are destroyed 26 years after file is closed. Records maintained by field level Offices of Counsel where patent applications are not prepared are destroyed 7 years after closure.· * * * * * Record source categories: Delete entry and replace with ·Inventors, reviewers, evaluators, officials of U.S. and foreign patent offices, and other persons having a direct interest in the file.· * * * * *
* * S100.70 System name: Invention Disclosure. System location: Office of the General Counsel, HQ DLA-DG, 8725 John J. Kingman Road, Stop 2533, Fort Belvoir, VA 22060-6221, and the offices of counsel of the DLA field activities. Official mailing addresses are published as an appendix to DLA's compilation of systems of records notices. Categories of individuals covered by the system: Employees and military personnel assigned to DLA who have submitted invention disclosures to DLA. Categories of records in the system: Inventor's name, Social Security Number, address, and telephone numbers; descriptions of inventions; designs or drawings, as appropriate; evaluations of patentability; recommendations for employee awards; licensing documents; and similar records. Where patent protection is pursued by DLA, the file may also contain copies of applications, Letters Patent, and related materials. Authority for maintenance of the system: 5 U.S.C. 301 , Departmental Regulations; 5 U.S.C. 4502 , General provisions; 10 U.S.C. 2320 , Rights in technical data; 15 U.S.C. 3710b , Rewards for scientific, engineering, and technical personnel of federal agencies; 15 U.S.C. 3711d , Employee activities; 35 U.S.C. 181-185 , Secrecy of Certain Inventions and Filing Applications in Foreign Countries; E.O. 9397 (SSN); and E.O. 10096 (Inventions Made by Government Employees) as amended by E.O. 10930 . Purpose(s): Data is maintained for making determinations regarding and recording DLA interest in the acquisition of patents, for documenting the patent process, and for documenting any rights of the inventor. The records may also be used in conjunction with the employee award program, where appropriate. Routine uses of records maintained in the system, including categories of users and the purposes of such uses: In addition to those disclosures generally permitted under 5 U.S.C. 552a(b) of the Privacy Act, these records or information contained therein may specifically be disclosed outside the DoD as a routine use pursuant to 5 U.S.C. 552a(b)(3) as follows: To the U.S. Patent and Trademark Office for use in processing applications and performing related functions and responsibilities under Title 35 of the U. S. Code. To foreign government patent offices for the purpose of securing foreign patent rights.

·To the National Archives and Records Administration as a record that has sufficient historical or other value to warrant its continued preservation by the U.S. Government, or for evaluation by the Archivist of the United States or the designee of the Archivist to determine whether the record has such value. Note: Records transferred to the Federal Records Centers for storage remain under the control of the DA and no accounting for disclosure is required under the Privacy Act. (7) 5 U.S.C. 552a(b)(7) ·To another agency or instrumentality of any governmental jurisdiction within or under the control of the United States for a civil or criminal law enforcement activity, if the activity is authorized by law, and if the head of the agency or instrumentality has made a written request to the Army or the DOD specifying the particular portion desired and the law enforcement activity for which the record is sought. (8) 5 U.S.C. 552a(b)(8) ·To a person pursuant to a showing of compelling circumstances affecting the health or safety of an individual if upon such disclosure, notification is transmitted to the last known address of such individual. (9) 5 U.S.C. 552a(b)(9) ·To either House of Congress, or, to the extent the matter is within its jurisdiction, any committee or subcommittee thereof, or any joint committee of Congress or subcommittee of any such joint committee. Requests from a Congressional member acting on behalf of a constituent are not included in this exception, but may be covered by a routine use exception to the Privacy Act (See applicable

Army system of records notice). (10) 5 U.S.C. 552a(b)(10) ·To the Comptroller General or authorized representatives, in the course of the performance of the duties of the Government Accountability Office. (11) 5 U.S.C. 552a(b)(11) ·Pursuant to the order of a court of competent jurisdiction. The order must be signed by a judge. (12) 5 U.S.C. 552a(b)(12) ·To a consumer reporting agency in accordance with section 3711(e) of Title 31 of the U.S. Code. The name, address, SSN, and other information identifying the individual; amount, status, and history of the claim; and the agency or program under which the case arose may be disclosed. However, before doing so, agencies must complete a series of steps designed to validate the debt and to offer the individual an opportunity to repay it. (d) DOD Blanket Routine Uses. In addition to specific routine uses which are listed in the applicable Army system of record notices, certain ·Blanket Routine Uses· apply to all DOD maintained systems of records. These are listed on the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy/> . These ·Blanket Routine Uses· are not specifically listed in each system of records notice as the specific routine uses are. The current DOD ·Blanket Routine Uses· are as follows·

The assessment of remote access may fall into several categories and is dependent on the specific architecture used and how the OSA creates its assessment environment. When an ESP is providing staff augmentation to the OSA and the OSA is providing all the systems used for remote access, then the OSA's policies and procedures apply and the ESP is not (printed page 83138) considered to be processing, storing, or transmitting CUI. When the ESP is using a Virtual Desktop solution, then the endpoint client device will be considered out of scope when it is configured to prevent storage, processing, or transmission of CUI on the end client beyond the Keyboard, Video, Mouse input that is part of the Virtual Desktop Infrastructure (VDI) solution. Establishing a VPN connection with MSP equipment brings that equipment into the OSA's assessment scope. The equipment must meet the OSA's requirements for external access and connection to the network. Depending on the processing performed by the ESP with the VPN connection, other requirements may apply. 18. CMMC Assessment Scope for Security Protection Assets and Data a. Scope and Authority Comment: Multiple comments asserted that the use of Security Protection Data and Security Protection Assets increases the scope and cost of CMMC assessments and recommend changes to the costs or removing SPD and SPA from the rule. One comment presented the increased scope as an inconsistency between NARA and NIST SP 800-171A Jun2018. A few comments asked what authority DoD uses to include SPD as part of CMMC assessment. Response: The commenter misread the rule's application to ESPs and SPA/SPD. Security Protection Assets are specified in NIST SP 800-171 R2 Sec 1.1 which states: ·The requirements apply only to components of nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components· The rule has been updated in table 3 to §·170.19(c)(1) and table 5 to §·170.19(d)(1) to change the definition and requirements of Security Protection Assets. The phrase ·irrespective of whether or not these assets process, store, or transmit CUI· has been removed from the SPA description and the CMMC assessment requirements have been changed to read ·Assess against CMMC security requirements that are relevant to the capabilities provided· Similar changes were made to the guidance documents. In order to clarify and address concerns about the perceived ·expansion· of requirements, the rule was revised to reflect that ESPs that only store SPD or provide an SPA and do not process, store, or transmit CUI do not require CMMC assessment or certification. b. Definition and Requirements Comment:

The OSA must conduct a Level 2 self-assessment in accordance with NIST SP 800-171A Jun2018 (incorporated by reference, see §·170.2) and the CMMC Level 2 scoping requirements set forth in §§·170.19(a) and (c) for the information systems within the CMMC Assessment Scope. The Level 2 self-assessment must be scored in accordance with the CMMC Scoring Methodology described in §·170.24 and the OSA must upload the results into SPRS. If a POA&M exists, a POA&M closeout self-assessment must be performed by the OSA when all NOT MET requirements have been remediated. The POA&M closeout self-assessment must be performed within 180-days of the Conditional CMMC Status Date. Additional guidance can be found in the guidance document listed in paragraph (c) of appendix A to this part. (2) Level 2 self-assessment with the use of Cloud Service Provider (CSP). An OSA may use a cloud environment to process, store, or transmit CUI in performance of a contract or subcontract with a requirement for the CMMC Status of Level 2 (Self) under the following circumstances: (i) The CSP product or service offering is FedRAMP Authorized at the FedRAMP Moderate (or higher) baseline in accordance with the FedRAMP Marketplace; or (ii) The CSP product or service offering is not FedRAMP Authorized at the FedRAMP Moderate (or higher) baseline but meets security requirements equivalent to those established by the FedRAMP Moderate (or higher) baseline. FedRAMP Moderate or FedRAMP Moderate equivalent is in accordance with DoD Policy. (iii) In accordance with §·170.19(c)(2), the

OSA's on-premises infrastructure connecting to the CSP's product or service offering is part of the CMMC Assessment Scope, which will also be assessed. As such, the security requirements from the Customer Responsibility Matrix (CRM) must be documented or referred to in the OSA's System Security Plan (SSP). (3) Level 2 self-assessment with the use of an External Service Provider (ESP), not a CSP. An OSA may use an ESP that is not a CSP to process, store, or transmit CUI in performance of a contract or subcontract with a requirement for the CMMC Status of Level 2 (Self) under the following circumstances: (i) The use of the ESP, its relationship to the OSA, and the services provided are documented in the OSA's SSP and described in the ESP's service description and CRM. (ii) The ESP services used to meet OSA requirements are assessed within the scope of the OSA's assessment against all Level 2 security requirements. (iii) In accordance with § 170.19(c)(2), the OSA's on-premises infrastructure connecting to the ESP's product or service offering is part of the CMMC Assessment Scope, which will also be assessed. As such, the security requirements from the CRM must be documented or referred to in the OSA's SSP. (4) Artifact retention. The artifacts used as evidence for the assessment must be retained by the OSA for six (6) years from the CMMC Status Date. § 170.17 CMMC Level 2 certification assessment and affirmation requirements. (a)

(Response) The costs for records storage and retrieval are not zero, but the additional storage costs likely to be incurred by covered entities as a result of this regulation are assumed to be zero. We assume that the private benefits from retaining records for the 1 and 2 years time frames required by this rule exceed the private costs of doing so. The range of comments to the proposal suggests that this assumption is reasonable. The private benefits of retaining records include enhancing a firm's ability to do the following: (1) file claims for shortages in quantities or qualities of products received, (2) respond to claims for shortages in quantities or qualities of products shipped, (3) sue suppliers for damages resulting from products received, and (4) respond to suits filed by downstream users for damages resulting from products shipped. FDA also believes that most firms retain these records for at least two years for income tax purposes. Therefore, FDA is not persuaded by the comment that most firms do not currently retain these records. Evidence gathered from interviews with FDA traceback investigation personnel indicate that current records retention practices in the food industry have not been a major obstacle to successful traceback investigations. In addition, comments suggest that records retention requirements should be linked to the shelf life of the product (which is presumably the current practice), and suggest retention times of 6 months to 2 years, depending on the shelf lives of the products. FDA interprets this evidence to indicate that even in the absence of records retention requirements, the private incentives to retain records would result in records retention times in excess of those required in the regulation. (Comment 190) One comment draws comparisons of the proposed records retention burden on small and large trucking firms. The comment contains a calculation of the number of records that would be required to be retained by a typical owner and operator of a single truck. The comment states that a 2 year retention requirement would obligate an owner and operator of a single truck to have on hand approximately 598 sets of load documents at any given time. If the average set of documents contained 20 pages, then this person would be required to retain approximately 11,960 pages at any given time. The comment suggests that this amount of documentation could be easily kept inside the truck in a side box and later transferred to an office corner or file cabinet at the owner's convenience. By assuming the number of documents to be retained by a firm is commensurate with the number of trucks owned by the firm, the comment argues that the proposed retention requirement would require large firms to retain an unreasonable amount of paperwork requiring substantially more storage space.

pre-award requirement. Another commenter appreciated the regulatory text which encourages contractors to consult with the Government for additional guidance if or when unsure of appropriate CMMC Level to assign a subcontract solicitation. Two commenters applauded the use of already established workforce qualifications while another concurred with the regulatory text permitting CMMC Certified Professionals (CCPs) to participate in assessments with oversight of a CMMC Certified Assessor (CCA). A commenter also expressed appreciation for the regulatory text's alignment to a specific version of the guidelines (i.e., NIST SP 800-171 R2). One commenter appreciated the video that DoD published to accompany and explain the proposed rule. Several comments cited the longstanding requirements of DFARS clause 252.204-7012 and cybersecurity risks of not implementing NIST SP 800-171 R2 as reasons that the 32 CFR part 170 CMMC Program final rule should be implemented as soon as possible. Response: The Department appreciates that several commenters expressed agreement to and encouragement for the CMMC Program requirement and its associated specific rule text. The DoD recognizes that not all entities impacted by these regulations hold the

same view of its requirements and appreciates those that took the time to express both positive and constructive feedback. Applicability Once CMMC is implemented in the 48 CFR part 204 CMMC Acquisition rule, the CMMC Program will require DoD to identify the CMMC Level and assessment type as a solicitation requirement and in the resulting contract for any effort that will cause a contractor or subcontractor to process, store, or transmit FCI or CUI on its unclassified information system(s). Once CMMC is implemented in the 48 CFR part 204 CMMC Acquisition rule, contractors handling FCI or CUI will be required to meet the CMMC Level and assessment type specified in the solicitation and resulting contract. Summary of Program Changes: DFARS Case 2019-D041 implemented DoD's original model for assessing contractor information security protections. The initial CMMC Program was comprised of five progressively advanced levels of cybersecurity standards and required defense contractors and subcontractors to undergo a certification process to demonstrate compliance with the cybersecurity standards associated with a given CMMC Level. In March 2021, the Department initiated an internal review of CMMC's implementation that engaged DoD's cybersecurity and acquisition leaders to refine policy and program implementation, focusing on the need to reduce costs for small businesses and align cybersecurity requirements to other Federal standards and guidelines. This review resulted in the revised CMMC Program, which streamlines assessment and certification requirements and improves implementation of the CMMC Program. These changes include: Eliminating Levels 2 and 4, and renaming the remaining three CMMC Levels as follows:

(Response) The agency does not agree with this comment. The comment fails to specify the nature of the chemical, physical, or biological tests being proposed, or what sampling scheme would be conducted to ascertain that the incoming ingredient is not contaminated. Moreover, only nontransporters are required to identify the specific source of each ingredient that was used to make every lot of finished product, and they are required to do so only if this information is reasonably available. FDA also notes that it has deleted this provision from § 1.337(a) of this final rule and instead inserted it in § 1.345(b) of this final rule. The agency believes records are more likely to be reasonably available to persons when they release food made from the ingredients than when the persons receive the ingredients under § 1.337 of this final rule. (Comment 96) A few comments request that the agency treat processing aids and incidental additives as it does commingled ingredients. The comments state that they are able to identify the source(s) in use in a facility when specific food products were produced, but are not able to identify the source of the processing aid or incidental additive used to produce a specific lot of food. (Response) The recordkeeping requirements in these regulations apply to all food unless specifically exempted. Processing aids may be food additives or a generally recognized as safe ingredient. In either case, they fall within the definition of food and are subject to these regulations. If the manufacturing process is such that a processing aid was used to make a specific lot of a finished food product, then the specific source of each processing aid should be identified in the records to the extent that information is reasonably available. (Comment 97) Several comments ask that the agency clarify the term "reasonably available" and provide guidance on what the agency considers is "reasonably available." One comment suggests that the agency use hypothetical case studies as guidance. (Response) What is "reasonably available" is going to depend on the particular circumstances. To illustrate this point in the proposed rule, FDA used a hypothetical case of a cookie maker. (See 68 FR 25188 at 25197.) A company that bakes cookies may source (printed page 71598)

From the NIST SP 800-172 Rev 3 Final Public Draft: Physical Protection 1419 03.1 0.01E Intr usion Alarms and Surveillance Equipment Monitor physical access to the facility where the system resides using physical intrusion alarms and surveillance equipment. DISCUSSION Physical intrusion alarms can be used to alert security personnel when unauthorized access to the facility is attempted. Alarm systems work in conjunction with physical barriers, physical access control systems, and facility security guards by triggering a response when these other forms of security have been compromised or breached. Physical intrusion alarms can include different types of sensor devices, including motion sensors, contact sensors, and broken glass sensors. Surveillance equipment includes video cameras installed at strategic locations throughout the

(Response) "Transporter" is defined in § 1.328 of this final rule to mean a person who has possession, custody, or control of an article of food in the United States for the sole purpose of transporting the food, whether by road, rail, water, or air. Transporter also includes a foreign person that transports food in the United States, regardless of whether that person has possession, custody, or control of that food for the sole purpose of transporting that food. If a person is

considered a nontransporter under the rule, then the person is not subject to the transporter provisions when transporting food, but must comply with the requirements applicable to nontransporters. The final rule applies to transporters regardless of their status as private or for-hire. For example, if a U.S. manufacturer hires a company to deliver its food, the delivery company is subject to the transporter provisions whether or not it is private or for-hire. If a person is considered a nontransporter under the final rule, then the person is not subject to the transporter provisions when transporting food. For example, a U.S. manufacturer that delivers its food to a grocery store must only keep the records required of a nontransporter. In this situation, the immediate previous sources of the manufacturer are the sources and transporters of the ingredients, and the immediate subsequent recipient of the manufacturer is the grocery store. (Comment 121) A number of comments note that the specific records being required of transporters are duplicative of the information being required of the immediate prior sources and the immediate subsequent recipients with respect to each other and that such redundancy is unnecessary because the agency could get the information from either or both of the immediate prior sources or immediate subsequent recipients. (Response) The requirements in the final rule ensure that transporters have records that would assist FDA in a tracing investigation. For example, if a manufacturer of a food product sends 300 boxes of that product to its buyer (the immediate subsequent nontransporter recipient), and the recipient only receives 200 boxes, records created by the transporters (or multiple transporter companies if more than one is used to transfer food between the nontransporter immediate previous source and the nontransporter immediate subsequent recipient) will be the only means of enabling FDA to learn how and when the remaining 100 boxes were diverted, and to where. In addition, under a similar scenario where a manufacturer of a food product sends 300 boxes of that product to its buyer and the recipient receives 400 boxes, transportation records will be the only means of enabling FDA to determine when the additional 100 boxes were introduced into the system and where they came from. Further support for requiring transporters to establish and maintain records is provided in response to comment 82 of this document.

Share Data for Mission Outcomes: Identify common data assets critical to stakeholders across FDA and make them widely available and consumable to drive operational efficiencies and excellence. Leverage valuable data assets and insights to develop new capabilities and services and enable public health innovation. Objectives Enhance Data Governance: Implement Artificial Intelligence (AI)-powered best practices for governance and data management that improve data quality, security, and the speed and accuracy of insights and decisions. Foster OneFDA Data Literacy: Educate the workforce on best practices and the benefits of consuming, analyzing, and making data-based decisions. (printed page 64438) Improve Data Visibility and Accessibility: Prioritize which data assets to make widely available first based on value to the mission and the most significant number of stakeholders. Enable Advanced Data Analytics: Ensure experts can easily combine and analyze information from various internal and external sources to gain comprehensive insights. Enhance Secure Data Exchange: Improve interoperable and secure data exchange and collaboration across FDA and its public health partners. Goal 5: Adopt AI and Mission-Driven Innovations: Drive exploration and address impacts of emerging technologies and trends, such as AI and virtual reality, on FDA's IT portfolio and regulatory operations. Proactively identify opportunities and risks to FDA's mission and inform responsible use of technology. Enhance partnerships with external experts to leverage these technologies and promptly respond to their impact. Objectives Balance Policy and Technology Value: Develop ethical guidance for technology use while maximizing business value, such as Guidance on AI Strategy. Ensure responsible actions by conducting comprehensive research and analysis to fully understand technological advancements' potential impacts and implications on society. Ensure Responsible Use of Innovations: Deploy technological innovations, such as AI/Machine Learning, responsibly with an understanding of regulatory impacts and effective risk response strategies. Establish appropriate guardrails where necessary. Provide Proactive Thought Leadership: Lead as a partner in creating novel use cases for emerging technologies through a deep understanding of business processes, industry, and technology. Stay at the forefront of technological advancements by harnessing industry expertise and fostering collaboration. Foster Innovation: Create an environment where innovative approaches are encouraged, identified, shared, and evaluated for use in driving operational efficiency and developing new capabilities. Apply a structured process to manage the innovation lifecycle from ideation to investment to adoption (or project shutdown) to produce usable innovations. Goal 6:

Assessors exercise judgment in determining when sufficient and adequate evidence has been presented to make an assessment finding. This is consistent with current DIBCAC High Assessments and

assessments conducted under the Joint Surveillance Voluntary Assessment (JSVA) program. Furthermore, to reduce burden to small businesses, the CMMC program has implemented flexibility with self-assessment, POA&Ms, and waivers. c. Cross-Functional Requirements and Artifacts Comment: Multiple comments maintained that DoD underestimated the cross-functional (Human Resources, Physical Security, Training, etc.) manhours and associated cost to collect artifacts and evidence in preparation for a C3PAO assessment. One comment stated the DoD's overestimation of CMMC Level 1 requirements would correspond to an underestimation of compliance costs. The comment referred to current NIST requirements and asserted that potential revisions would force changes to POA&Ms causing additional costs beyond those included in the estimates. The comment suggested the DoD should determine the range of potential compliance timelines, the use and value of existing and planned POA&Ms, and true certification costs, both for initial compliance as well as ongoing maintenance and oversight. One commentor claimed too much funding was expended over the past 5 years for the CMMC database system. Response: OSCs prepare for C3PAO assessments based upon NIST guidelines as addressed in § 170.17. The cost and time estimates represent the time to gather the evidence to address all assessment objectives are derived averages based on internal expertise and public feedback in accordance with OMB Circular A-4 Regulatory Impact Analysis: A Primer. The size and complexity of the network within scope of the assessment impacts the costs as well. The time estimates represent average derived estimates based on internal expertise and public feedback in accordance with OMB Circular A-4. The size and complexity of the network within scope of the assessment impacts the time estimates as well. The DoD does not concur with the commenter's claim that too much funding has been spent to develop the DoD's database for the CMMC Program. d. Duplication or Overlap Comment: One comment asserted CMMC requirements may be duplicative or conflict with existing utility industry compliance requirements that address CUI, since utility companies will not require CMMC Level 3 certification. They proposed the utilities and the DoD collaborate to harmonize requirements to limit the financial burden. One comment highlighted a concern that cost for companies that have multiple contracts, each requiring different CMMC Program requirements. Concerns were specifically based on the increased costs from CMMC Level 2 to CMMC Level 3 compliance and assuming costs would be borne by contractors. They expressed similar concerns about costs for FedRAMP certification, given a purported backlog in FedRAMP authorizations. Response:

Two respondents commented on the exclusions process itself. One respondent commented that the exclusion process is seriously flawed because it does not connect the acts conducted by those at higher levels in DoD with the actions of the contracting officers in any rational time phased application that would help offerors understand the proposal and business risk involved in any given source selection process. This respondent further commented that it is fundamentally unclear whether an exclusion will be made on a case-by-case basis or be a blanket exclusion of a contractor or subcontractor, and that it is unclear at what point in the acquisition process such exclusions may be authorized or executed. Under the new rule's language, a source could be excluded before, during, and/or after a contract award (whether as prime or subcontractor). One respondent suggests that its concerns that DoD can reject or modify acquisitions based upon concerns about supply chain integrity could be addressed by having any sensitive finding subject to review, and recommendation for approval or disapproval to the Secretary of Defense, by the DoD General Counsel, or a committee appointed by the Secretary of Defense charged with assuring the validity of such concerns and their sensitivity for release to suppliers. Response: Suppliers are expected to manage supply chain risk in their offerings. Under section 806 and the rule, exclusion of a source may occur during source selection before award (using an evaluation factor) or after award (by withholding consent to a subcontract). Exclusion of a source would be on a case-by-case basis, as the (printed page 67248) risk tolerance is not the same for all procurement actions. The authorization and recommendation mechanisms and participants described in the rule are mandated by the statute. d. Dispute Mechanism Comment: Two respondents commented on the need for an impartial process for addressing concerns. One respondent urged that the interim rule reinforce the need for a fair opportunity pre- and post-exclusion for concerns to be addressed by the contractor or vendor at issue. One respondent commented that neither section 806 of the NDAA for FY 2011 nor the interim rule provide for any procedures for proposed contractors or subcontractors to challenge a possible exclusion determination where DoD decides to limit the disclosure of information. This respondent further stated that DoD should provide some dispute mechanism for exclusion in protest and claim matters, whereby counsel for offerors, contractors, and proposed subcontractors can represent their clients and obtain access to information under protective order or clearance to assure that the required process was followed and proper grounds for invocation of the exclusion exist. Response:

Exclusions using the authority of section 806 will be based generally on classified intelligence information. A dispute resolution mechanism is not appropriate under those circumstances.

3.5.1 | Path Validation ... 3.5.1 and 3. 3.5.1 Path Validation The client certificate shall be validated in accordance with the certification path validation rules specified in Section 6 of [19].

OSCs may submit any appeal arising from CMMC Level 2 assessment activities to C3PAOs as addressed in § 170.9(b)(19). OSCs may request a copy of the process from their C3PAO. The rule has been revised to reflect that any dispute over assessment findings which cannot be resolved by the C3PAO may be escalated to the CMMC AB by either the C3PAO or the OSC. The decision rendered by the CMMC AB will be final as stated in § 170.8(b)(16). Appeals pertaining to an assessor's professional conduct that is not resolved with the C3PAO will also be escalated and resolved by the CMMC AB. As addressed in § 170.9(b)(13), the C3PAO will have a quality assurance individual responsible for managing the appeals process in accordance with ISO/IEC 17020:2012(E) and ISO/IEC 17011:2017(E). Identification of the C3PAO staff that an OSC should interface with is beyond the scope of this rule. It is a business decision that may vary by C3PAO and should be addressed between the OSC and C3PAO prior to conduct of an assessment. The supplemental documents listed in Appendix A provide additional guidance to aid in CMMC (printed page 83143) implementation and are not authoritative. In the event of conflicts with the security requirements incorporated by reference, this rule and NIST SP 800-171A Jun2018 or NIST SP 800-172A Mar2022 guidance will always take precedence. Disputes regarding the CMMC level specified in a contract solicitation should be addressed with the contracting officer using normal pre-award or post-award communications processes. No revision to the rule is required. Selection of the CMMC level is a DoD risk-based decision made by the Program Manager or Requiring Activity.

23. CMMC Cybersecurity Requirements a. NIST SP 800-171 R2 Requirements Comment: Several comments were received regarding FIPS-validated cryptography. Some recommended mitigating delays with FIPS validation testing and reducing the risk of CMMC assessment failures by allowing FIPS POA&Ms or POA&M extensions, waivers, or making encryption an organizationally defined parameter (ODP). Similarly, some recommended the DoD accept alternate FIPS solutions such as commercially viable modules with FIPS-approved protocols or FIPS-compliant-as opposed to FIPS-validated-protocols. One comment recommended that DoD collaborate with NIST to either improve the processing of FIPS validation testing and/or to define the encryption ODP for NIST SP 800-171 Revision 3. One comment recommended DoD work with NIST to align NIST ODPs in NIST SP 800-171 Revision 3 to DoD ODPs defined in the CMMC Rule for CMMC Level 3 to ensure consistency. Another commenter asked if FIPS 140-3 was an acceptable FIPS implementation.

impending problems. Traditionally, most logs have not been analyzed in a real-time or near-real-time manner. Without sound processes for analyzing logs, the value of the logs is significantly reduced.

- Provide adequate support for all staff with log management responsibilities. While defining the log management scheme, organizations should ensure that they provide the necessary training to relevant staff regarding their log management responsibilities as well as skill instruction for the needed resources to support log management. Support also includes providing log management tools and tool documentation, providing technical guidance on log management activities, and disseminating information to log management staff.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 ADVERSARY EFFECTS 1450

(3) Upon entrance into military service or civilian employment with DA, individuals are asked to provide their SSN. The SSN becomes the service or employment number for the individual and is used to establish personnel, financial, medical, and other official records. After an individual has provided his or her SSN for the purpose of establishing a record, the Privacy Act Statement is not required if the individual is only requested to furnish or verify the SSN for identification purposes in connection with the normal use of his or her records. If the SSN is to be used for a purpose other than identification, the individual must be informed whether disclosure of the SSN is mandatory or voluntary; by what statutory authority the SSN is solicited; and what uses will be made of the SSN. This notification is required even if the SSN is not to be maintained in a Privacy Act system of records. (4) When asking an individual for his or her SSN or other personal information that will be maintained in a system of records, the individual must be provided with a Privacy Act Statement. (b) Privacy Act Statement (PAS). (1) A Privacy Act Statement is required whenever

personal information is requested from an individual and will become part of a Privacy Act system of records. The information will be retrieved by the individual's name or other personal identifier (See 5 U.S.C. 552a(e)(3)). (2) The PAS will ensure that individuals know why the information is being collected so they can make an (printed page 46057) informed decision as to providing the personal information. (3) In addition, the PAS will include language that is explicit, easily understood, and not so lengthy as to deter an individual from reading it. (4) A sign can be displayed in areas where people routinely furnish this kind of information, and a copy of the PAS will be made available upon request by the individual. (5) Do not ask the person to sign the PAS. (6) A Privacy Act Statement must include the following four items- (i) Authority: Cite the specific statute or Executive Order, including a brief title or subject that authorizes the DA to collect the personal information requested. (ii) Principal Purpose (s): Cite the principal purposes for which the information will be used. (iii) Routine Uses: A list of where and why the information will be disclosed OUTSIDE of DOD. Applicable routine uses are published in the applicable Privacy Act system of records notice(s). If none, the language to be used is: Routine Use(s): None. However the Blanket Routine Uses set forth at the beginning of the Army's compilation of systems of records notices apply. (iv) Disclosure:

(B) Records maintained solely for statistical research or program evaluation purposes and which are not used to make decisions on the rights, benefits, or entitlement of an individual except for census records which may be disclosed under 13 U.S.C. 8 , may be exempt pursuant to 5 U.S.C. 552a(k)(4) . (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and (k) (4) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(4) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violations of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information is retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (8) System identifier and name. A0190-5 OPMG, Vehicle Registration System. (i) Exemption. Parts of this system of records may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its primary function any activity pertaining to the enforcement of criminal laws. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(j) (2) from subsections 5 U.S.C. 552a(c)(3) , (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (e)(4)(H), (e)(4)(I), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons.

From the NIST SP 800-172 Rev 3 Final Public Draft: The adversary's efforts or resources cannot be applied or are wasted. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025

DoD agreed with the commenter that the government does not have authority over transactions between the OSC and C3PAO. The roles and responsibilities of the government are set forth in §170.6. The interaction between the CMMC Accreditation Body and C3PAOs is governed by the requirements of this rule in §§170.8 and 170.9, including Conflict of Interest, Code of Professional Conduct, and Ethics policies, as well as ISO/IEC standards. All DCMA DIBCAC assessors comply with DoD regulations regarding the cybersecurity workforce, to include DoD Directives 8140 and 8570 and other internal training standards. DCMA DIBCAC assessors' credentials for CMMC Levels 2 and 3 exceed the training

that CCPs and CCAs complete through Approved Training Providers and include industry certification and a security clearance. Additionally, DCMA DIBCAC assessors must take the CMMC certification examinations. DoD's contract with the CMMC AB assigned places responsibility for Level 2 assessment interpretation to the CMMC Accreditation Body. The CMMC Accreditation Body publishes assessment procedures and guidance for C3PAOs conducting CMMC Level 2 Certification Assessments. The CMMC AB is required to provide the CMMC PMO with all plans or changes related to its own activities and activities within the CMMC Ecosystem for review prior to implementation and publication. The DCMA DIBCAC is responsible for CMMC Level 3 assessment interpretation and will use the same process that is used for DIBCAC High Assessments. Management oversight of the CMMC Program was realigned from the OUSD(A&S) to the Office of the DoD CIO for better integration with the Department's other DIB cybersecurity related initiatives. Comments pertaining to DoD's organizational structure are not relevant to the content of this rule. The DoD CIO is responsible for all matters relating to the DoD information enterprise, including network policy and standards and cybersecurity. In this capacity, the DoD CIO prescribes IT standards, including network and cybersecurity standards. The DoD CIO oversees programs to enhance and supplement DIB company capabilities to safeguard DoD information that resides on or transits DIB unclassified information systems. The DoD reviewed and assessed whitepapers that were submitted by RFI respondents and determined that no single respondent could meet all the broad facets required to serve as the CMMC Accreditation Body. §§ 170.8, 170.9, and 170.10 document the roles of the CMMC AB and the CAICO in managing a complaints/appeals process for CCAs, CCPs, and C3PAOs. OSCs concerned about the results of a Level 2 or Level 3 Certification assessment have a route of appeal documented in § 170.9. DoD, as the contracting entity, is not subject to service level agreements. Vendors and prospective vendors can voice concerns with the relevant contracting officer. External organizations may utilize existing DoD procedures to file complaints or concerns against any DoD organization.

Assets in scope for CMMC Level 1 Self-Assessment. OSA information systems which process, store, or transmit FCI are in scope for CMMC Level 1 and must be self-assessed against applicable CMMC security requirements. (2) Assets not in scope for CMMC Level 1 Self-Assessment. -(i) Out of Scope Assets. OSA information systems which do not process, store, or transmit FCI are outside the scope of the CMMC Level 1 Self-Assessment. There are no documentation requirements for these assets. (ii) Specialized Assets. Specialized Assets are those assets that can process, store, or transmit FCI but are unable to be fully secured, including: Internet of Things (IoT) devices, Industrial Internet of Things (IIoT) devices, Operational Technology (OT), Government Furnished Equipment (GFE), Restricted Information Systems, and Test Equipment. Specialized Assets are not part of the Level 1 CMMC Assessment Scope and are not assessed against CMMC security requirements. (3) CMMC Level 1 Self-Assessment scoping considerations. To scope a CMMC Level 1 Self-Assessment, OSAs should consider the people, technology, facilities, and External Service Providers (ESP) within its environment that process, store, or transmit FCI. (c) CMMC Level 2 Scoping. Prior to performing a Level 2 CMMC assessment, the OSA must specify the CMMC Assessment Scope. (1) The CMMC Assessment Scope for CMMC Level 2 is based on the specification of asset categories and their respective requirements as defined in table 1 to this paragraph. Additional information is available in the guidance document listed in paragraph (f) of appendix A to this part. (printed page 89134) Table 1 to § 170.19(c)(1) CMMC Level 2 Asset Categories and Associated Requirements

Asset category	Asset description	OSA requirements	CMMC assessment requirements
Assets that are in the Level 2 CMMC Assessment Scope	Controlled Unclassified Information (CUI) Assets	Assets that process, store, or transmit CUI	Document in the asset inventory
	Document in the System Security Plan (SSP)	Document in the network diagram of the CMMC Assessment Scope	Assess against CMMC security requirements.
	Prepare to be assessed against CMMC security requirements.	Security Protection Assets	Assets that provide security functions or capabilities to the OSA's CMMC Assessment Scope, irrespective of whether or not these assets process, store, or transmit CUI
	Document in the asset inventory	Document in SSP	Document in the network diagram of the CMMC Assessment Scope
	Prepare to be assessed against CMMC security requirements.	Assess against CMMC security requirements.	Contractor Risk Managed Assets
	Assets that can, but are not intended to, process, store, or transmit CUI because of security policy, procedures, and practices in place	Assets are not required to be physically or logically separated from CUI assets.	

From the NIST SP 800-172 Rev 3 Final Public Draft: Establish agreements and procedures with entities involved in the supply chain for 2522 the system, system component, or system service for the [Selection (one or more): notification of supply chain compromises; results of assessments or audits; [Assignment: organization-defined information]]. DISCUSSION Establishing agreements and

procedures facilitates communications among supply chain entities. Early notification of compromises and potential compromises in the supply chain that may adversely affect or have adversely affected organizational systems or system components is essential for organizations to effectively respond to such incidents. The results of assessments or audits may include open-source information that contributed to a decision or result and could be used to h

Department of Commerce Howard Lutnick, Secretary National Institute of Standards and Technology Craig Burkhardt, Acting Under Secretary of Commerce for Standards and Technology and Acting NIST Director NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 Certain equipment, instruments, software, or materials, commercial or non-commercial, are identified in this paper in order to specify the experimental procedure adequately. Such identification does not imply recommendation or endorsement of any product or service by NIST, nor does it imply that the materials or equipment identified are necessarily the best available for the purpose. There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. Organizations are encouraged to review all draft publications during public comment periods and provide feedback to NIST. Many NIST cybersecurity publications, other than the ones noted above, are available at <https://csrc.nist.gov/publications>. Authority This publication has been developed by NIST in accordance with its statutory responsibilities under the Federal Information Security Modernization Act (FISMA) of 2014, 44 U.S.C. § 3551 et seq., Public Law (P.L.) 113-283. NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems, but such standards and guidelines shall not apply to national security systems without the express approval of appropriate federal officials exercising policy authority over such systems. This guideline is consistent with the requirements of the Office of Management and Budget (OMB) Circular A-130. Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority. Nor should these guidelines be interpreted as altering or superseding the existing authorities of the Secretary of Commerce, Director of the OMB, or any other federal official. This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST. NIST Technical Series Policies Copyright, Use, and Licensing Statements NIST Technical Series Publication Identifier Syntax Publication History Approved by the NIST Editorial Review Board on YYYY-MM-DD [Will be added to final publication.] Supersedes NIST Series XXX (Month Year) DOI [Will be added to final publication, if applicable.] How to Cite this NIST Technical Series Publication: Ross R, Pillitteri V (2025) Enhanced Security Requirements for Protecting Controlled Unclassified Information. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800- 172r3 fpd. <https://doi.org/10.6028/NIST.SP.800-172r3.fpd> Author ORCID iDs Ron Ross: 0000-0002-1099-9757 Victoria Pillitteri: 0000-0002-7446-7506

(e) Contracting officers shall also refer to 3.104-4 for procedures related to the disclosure, protection, and marking of contractor proprietary business information, contractor bid or proposal information, and source selection information submitted to the Government. (f) The contracting officer shall follow agency procedures when providing any CUI to an offeror to ensure offeror compliance with the requirements in 32 CFR part 2002 . 4.403-6 CUI incident reports. (a) Agencies shall protect against the improper use or release of information that includes contractor proprietary business information or contractor-attributable information to the extent required by law. See paragraph (g)(9) of 52.204-XX, Controlled Unclassified Information, for details on how contracting officers may use or share this information. (b) For CUI in a non-Federally-controlled facility- (1) Designate the agency point of contact to whom the contractor reports a CUI incident in the SF XXX Part C, Section IV. When the SF XXX is not used in a contract, the point of contact is the contracting officer (see 52.204-YY(b)). (2) The SF XXX will list any special incident reporting requirements for CUI Specified. (3) Upon notification of a CUI incident, the contracting officer shall notify the requiring activity of the CUI incident as soon as practicable and in accordance with agency procedures. If the CUI incident occurs on an order against an indefinite delivery contract, the ordering agency contracting officer shall make the contracting officer for the

indefinite delivery contract aware of the notification. (c) When the contractor is required to provide information system images preserved under the requirements of paragraph (g)(4) of the clause at 52.204-XX or as directed by the contracting officer in response to contractor notification under paragraph (b)(2) of the clause at 52.204-YY, in accordance with agency procedures, the contracting officer shall provide instructions to the contractor for submitting the system images. The contractor is required to hold the system images for 90 days unless the Government declines interest. (d)(1) The contracting officer shall not interpret a contractor's report of a CUI incident to mean that the contractor or a subcontractor at any tier failed to provide adequate safeguards for CUI or otherwise failed to meet the requirements of the clause at 52.204-XX, without further analysis by the agency. (2) When a CUI incident is reported, the contracting officer shall consult with appropriate agency personnel (e.g., program office or requiring activity) before taking any action under the contract related to the CUI incident. When the contract includes the clause at 52.204-XX, the contracting officer shall consider such CUI incidents in the context of an overall assessment of the contractor's compliance with the requirements of the clause at 52.204-XX.

that a regulated entity must review and modify security measures. Section 164.306 does not explicitly reference specific security measures, and we are concerned that recent caselaw has highlighted conditions that may cause regulated entities to misinterpret regulatory text that connects the maintenance provision at 45 CFR 164.306(e) with the documentation requirements in 45 CFR 164.316 and the administrative safeguards. Through OCR's educational and enforcement efforts, we also have observed inadequacies in compliance with security management processes. For example, some regulated entities have (printed page 936) incorrectly interpreted the standards to not require implementing administrative safeguards, such as risk analyses, for all relevant electronic information systems. Some regulated entities have not documented in writing their policies, procedures, plans, and analyses. [442] As discussed above, many mistakenly treated ·addressable· implementation standards as optional. [443] Enforcement experience has shown that regulated entities generally do not perform all elements of the risk management process that are fundamental to protecting the confidentiality, integrity, and availability of ePHI and to cybersecurity more broadly. In addition, since the Security Rule was issued in 2003 and revised in 2013, newer, more protective security technology has become widely available to regulated entities, and best practices for securing electronic information have evolved. NIST has published numerous guides, including its recent Cybersecurity Framework 2.0, providing resources for establishing and implementing policies and practices to better manage cybersecurity risks. [444] OCR is drawing upon its enforcement experience, as well as best practices, guidelines, processes, and procedures for improving cybersecurity to propose changes to these standards to better protect ePHI that a regulated entity creates, receives, maintains, or transmits. We believe that these proposals would help ensure that regulated entities implement compliance activities that are consistent with recommendations made by NIST, the HHS 405(d) program, and standards setting bodies regarding cybersecurity. Because business associates are directly liable for compliance with the Security Rule, in our 2013 Security Rule revisions we did not require covered entities to implement any additional safeguards to ensure that their business associate is in fact in compliance. [445]

, DoD established a Regulatory Reform Task Force to review and validate DoD regulations, including the DFARS. A public notice of the establishment of the DFARS Subgroup to the DoD Regulatory Reform Task Force, for the purpose of reviewing DFARS provisions and clauses, was published in the Federal Register at 82 FR 35741 on August 1, 2017, and requested public input. No public comments were received on this provision. Subsequently, the DoD Task Force reviewed the requirements of DFARS provision 252.204-7004, Alternate A, System for Award Management, and determined that the DFARS coverage was redundant and recommended removal. II. Applicability to Contracts at or Below the Simplified Acquisition Threshold and for Commercial Items, Including Commercially Available Off-the-Shelf Items This rule merely removes obsolete DFARS provision 252.204-7004, Alternate A, System for Award Management. Therefore, the rule does not impose any new requirements on contracts at or below the simplified acquisition threshold and for commercial items, including commercially available off-the-shelf items. III. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866 , Regulatory

Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804 . IV. Executive Order 13771 This rule is not an E.O. 13771 , Reducing and Controlling Regulatory Costs, regulatory action, because this rule is not significant under E.O. 12866 . V. Publication of This Final Rule for Public Comment Is Not Required by Statute The statute that applies to the publication of the Federal Acquisition Regulation (FAR) is the Office of Federal Procurement Policy statute (codified at title 41 of the United States Code). Specifically, 41 U.S.C. 1707(a)(1) requires that a procurement policy, regulation, procedure or form (including an amendment or modification thereof) must be published for public comment if it relates to the expenditure of appropriated funds, and has either a significant effect beyond the internal operating procedures of the agency issuing the policy, regulation, procedure, or form, or has a significant cost or administrative impact on contractors or offerors. This final rule is not required to be published for public comment, because DoD is not issuing a new regulation; rather, this rule merely removes an obsolete requirement from the DFARS. VI. Regulatory Flexibility Act

(i) The Level 1 self-assessment must be performed using the objectives defined in NIST SP 800-171A Jun2018 (incorporated by reference, see § 170.2) for the security requirement that maps to the CMMC Level 1 security requirement as specified in table 1 to paragraph (c)(1)(ii) of this section. In any case where an objective addresses CUI, FCI should be substituted for CUI in the objective. (ii) Mapping table for CMMC Level 1 security requirements to the NIST SP 800-171A Jun2018 objectives. Table 2 to § 170.15 (c)(1)(ii) ·CMMC Level 1 Security Requirements Mapped to NIST SP 800-171A Jun2018 CMMC Level 1 security requirements as set forth in § 170.14(c)(2) NIST SP 800-171A Jun2018 AC.L1-b.1.i 3.1.1 AC.L1-b.1.ii 3.1.2 AC.L1-b.1.iii 3.1.20 AC.L1-b.1.iv 3.1.22 IA.L1-b.1.v 3.5.1 IA.L1-b.1.vi 3.5.2 MP.L1-b.1.vii 3.8.3 PE.L1-b.1.viii 3.10.1 First phrase of PE.L1-b.1.ix (FAR b.1.ix.*) 3.10.3 Second phrase of PE.L1-b.1.ix (FAR b.1.ix.*) 3.10.4 Third phrase of PE.L1-b.1.ix (FAR b.1.ix.*) 3.10.5 SC.L1-b.1.x 3.13.1 SC.L1-b.1.xi 3.13.5 SI.L1-b.1.xii 3.14.1 SI.L1-b.1.xiii 3.14.2 SI.L1-b.1.xiv 3.14.4 SI.L1-b.1.xv 3.14.5 *.Three of the 48 CFR 52.204-21 requirements were broken apart by ·phrase· when NIST SP 800-171 R2 was developed. (iii) Additional guidance can be found in the guidance document listed in paragraph (b) of appendix A to this part. (2) Artifact retention. The artifacts used as evidence for the assessment must be retained by the OSA for six (6) years from the CMMC Status Date. § 170.16 CMMC Level 2 self-assessment and affirmation requirements. (a) Level 2 self-assessment. To comply with Level 2 self-assessment requirements, the OSA must meet the requirements detailed in paragraphs (a)(1) and (2) of this section. An OSA conducts a Level 2 self-assessment as detailed in paragraph (c) of this section to achieve a CMMC Status of either Conditional or Final Level 2 (Self). Achieving a CMMC Status of Level 2 (Self) also satisfies the requirements for a CMMC Status of Level 1 (Self) detailed in § 170.15 for the same CMMC Assessment Scope. (1) Level 2 self-assessment requirements. The OSA must complete and achieve a MET result for all security requirements specified in § 170.14(c)(3) to achieve the CMMC Status of Level 2 (Self). The OSA must conduct a self-assessment in accordance with the procedures set forth in paragraph (c)(1) of this section and submit assessment (printed page 83228) results in Supplier Performance Risk System (SPRS). To maintain compliance with the requirements for a CMMC Status of Level 2 (Self), the OSA must conduct a Level 2 self-assessment every three years and submit the results in SPRS, within three years of the CMMC Status Date associated with the Conditional Level 2 (Self). (i) Inputs to SPRS. The Level 2 self-assessment results in the SPRS shall include, at minimum, the following information: (A) CMMC Level. (B) CMMC Status Date. (C) CMMC Assessment Scope. (D) All industry CAGE code(s) associated with the information system(s) addressed by the CMMC Assessment Scope.

Implementing the proposals likely would require regulated entities to engage workforce members or consultants for certain activities. The Department assumes that an information security analyst would perform most of the activities proposed in the NPRM, consistent with the existing Security Rule requirements. The Department expects that a computer and information systems manager would revise policies and procedures, a training and development specialist would revise the necessary workforce training, a lawyer would revise business associate agreements, and a compensation and benefits manager would revise health plan documents for plan sponsors. To the extent that these assumptions affect the Department's estimate of costs, the Department solicits comment on its assumptions, particularly assumptions in which the Department identifies the level of workforce member (e.g., analyst, manager, licensed professional) that would be engaged in activities and the amount of time that particular types of workforce members spend conducting activities related to this RIA as further described below. Table 3 lists pay rates for occupations referenced in the cost estimates for the NPRM. Table 3-Occupational Pay Rates 944 Occupation code and title Fully

loaded hourly wage 2023 Average hourly wage 15-1212·Information Security Analysts \$119.94 \$59.97 13-1151·Training and Development Specialists 69.20 34.60 11-3111·Compensation and Benefits Manager 145.14 72.57 11-3021·Computer and Information Systems Managers 173.76 86.88 23-1011·Lawyers 169.68 84.84 13-1111·Management Analysts 111.08 55.54 43-0000·Office and Administrative Support Occupations 46.10 23.05 The Department assumes that most regulated entities would be able to incorporate changes to their workforce training into existing cybersecurity awareness training programs and Security Rule training rather than conduct a separate training because the total time frame for compliance from date of publication of a final rule would be 240 days. [945] Regulated Entities Affected The changes proposed in this NPRM would apply to covered entities (i.e., health care providers that conduct covered electronic transactions, health plans, and health care clearinghouses) and their business associates (including subcontractors). The Department estimates the number of covered entities to be 822,600 business establishments (see table 4). By calculating costs for establishments, rather than firms, [946] some burdens may be overestimated because certain costs would be borne by a parent organization rather than each separate facility. Similarly, benefits and transfers would be overestimated because entity assumptions flow through to those quantifications. However, decisions about the level of an organization that is responsible for implementing certain requirements likely varies across the health care industry. The Department requests data on the extent to which certain burdens are borne by each facility versus an umbrella organization. According to Census data, [947]

Functionality requirements are the technical security features (referred to as "security enforcing functions") that are implemented in an IT system in order to support the system's requirements for the maintenance of confidentiality, integrity, and availability. The ITSEC defines ten example functionality classes: FI, F2, F3, F4, F5, F6, F7, F8, F9, and FIO. Functionality classes FI - F5 are roughly equivalent to the TCSEC classes CI, C2, BI, B2, and B3.^ Functionality classes F6 FIO represent integrity, availability, data communications integrity, data communications confidentiality, and data communications confidentiality and integrity, respectively. The System Security Study Committee was formed in 1988 in response to a request from the Defense Advance Research Projects Agency (DARPA) to address the security and trustworthiness of U.S. computing and communications systems. The Committee, composed of 16 individuals from industry and academia including computer and communications security researchers and practitioners and software engineers, was charged with developing a national research, engineering, and policy agenda to help the U.S. achieve a more trustworthy computing technology base by the end of the century. In 1991, the Committee published the Computers at Risk - Safe Computer in the Information Age [5] report, which presents the Committee's assessment of key computer and communications security issues and its recommendations for enhancing the security and trustworthiness of the U.S. computing and communications infrastructure. * since encryption algorithms are subject to national export control, statements specifying data encryption have been stated as advisories rather than requirements. This will allow the data encryption mechanism to be packaged by the vendor as a separate option and not "bundled" into the baseline system.

According to 45cfr160: [Skip to main content](#main-content) Menu [!GovInfo logo](/media/GovInfo_logo_gray.png)](/) [Search](#searchHolder) * Browse + [A to Z](/browse-a-z) + [Category](/app/browse/category) + [Date](/app/browse/date) + [Committee](/browse/committee) + [Author](/app/browse/author) * About + [About](/about) + [Policies](/about/policies) + [Authentication](/about/authentication) + [Digital Preservation](/about/digital-preservation) + [History](/about/history) + [Agency Submission](/about/agency-submission) + [U.S. Government Information](/about/us-gov-info) + [FDsys Retirement](/about#fdsys-transition) * Developers + [Developer Hub](/developers) + [API](https://api.govinfo.gov/docs) + [Bulk Data Repository](%20/bulkdata) + [Link Service](/link-docs) + [Feeds](/feeds) + [Sitemaps](/sitemaps) + [System Design](/developers/system-design) * Features + [All Features](/features) + [Featured Content](/features/featured-content) + [News](/features/news) + [Release Notes](/features/release-notes) + [Finding Publications](/features/finding-publications) * Help + [Help](/help) + [Finding Information](%20/help/finding-info) + [What's Available](/help/whats-available) + [Tutorials and Handouts](/help/tutorials-handouts) + [Other Resources](%20/help/other-resources) * Feedback + [Submit Feedback](https://www.surveymonkey.com/r/govinfo-feedback-survey) + [Contact Us](/contact) * [Toggle the Search Widget Search](#searchHolder) # Page Not Found ![Icon: Share using Facebook](/sites/default/files/fb-icon-white.png) ![Icon: Share using Email](/sites/default/files/email-icon-white.png) ![Icon: Copy Link URL](/sites/default/files/link-icon-white.png) [Help](/help/other) --- **Error occurred.

Example 1	Example 2	Example 3
Control(s)	Periodic vulnerability assessments Patch deployment capabilities	Unique user accounts Authentication method(s) Audit logs Audit log alerting/evaluation Power generator AC unit Upstream network provider Web load balancers Web servers
KPI	Percentage of vulnerabilities patched Unsuccessful logins in a 1-hour period Outage time in hours	Leading KRI Number of computers with critical (CVSS 10) vulnerabilities that have not been patched in 10 days 4 failed logins for a single user 29 failed logins across all users Outages affecting more than 5 %of customers that have lasted 1.5 hours Outages lasting over 2 hours that affect fewer than 5 %of customers
Lagging KRI	Number of computers with CVSS 10 vulnerabilities that have not been patched in 15 days 5 failed logins for a single user 30 failed logins across all users	Current outages affecting more than 5 %of customers that have lasted more than 2 hours

Control(s) | · Periodic vulnerability assessments · Patch deployment capabilities | · Unique user accounts · Authentication method(s) · Audit logs · Audit log alerting/evaluation | · Power generator · AC unit · Upstream network provider · Web load balancers · Web servers | | KPI | Percentage of vulnerabilities patched | · Unsuccessful logins in a 1-hour period | · Outage time in hours | | Leading KRI | Number of computers with critical (CVSS 10) vulnerabilities that have not been patched in 10 days | · 4 failed logins for a single user · 29 failed logins across all users | · Outages affecting more than 5 %of customers that have lasted 1.5 hours · Outages lasting over 2 hours that affect fewer than 5 %of customers | | Lagging KRI | Number of computers with CVSS 10 vulnerabilities that have not been patched in 15 days | · 5 failed logins for a single user · 30 failed logins across all users | · Current outages affecting more than 5 %of customers that have lasted more than 2 hours |

(B) For a commercial central station, protective signaling service station, or residential monitoring station, there will be a sufficient number of trained guards available to respond to alarms. Guards will be cleared only if they have the ability and responsibility to access the area or container(s) housing classified material (i.e., keys to the facility have been provided or the personnel are authorized to enter the building or check the container or area that contains classified material). (C) Uncleared guards dispatched by a commercial central station, protective signaling service station, or residential monitoring station in response to an alarm will remain on the premises until a designated, cleared representative of the facility arrives, or for a period of not less than 1 hour, whichever comes first. If a cleared representative of the facility does not arrive within 1 hour following the arrival of the guard, the central control station must provide the CSA with a report of the incident that includes the name of the subscriber facility, the date and time of the alarm, and the name of the subscriber's representative who was contacted to respond. A report will be submitted to the CSA by the end of business on the next business day. (D) Subcontracted guards must be under a classified contract with either the installing alarm service company or the cleared facility. (printed page 83341) (iii) The response time will be in accordance with the provisions in paragraphs (c)(1) through (c)(3) in this section as applicable. When environmental factors (e.g., traffic, distance) legitimately prevent meeting the requirements for TOP SECRET information, as indicated in paragraph (c)(3) in this section, the CSA may authorize up to a 30-minute response time. The CSA approval will be documented on the alarm system description form and the specified response time will be noted on the alarm certificate. The requirement for response is 80 percent within the time limits. (4) Installation. The IDS will be installed by an NRTL-approved entity or by an entity approved in writing by the CSA. When connected to a commercial central station, GCMS, national industrial monitoring station, or residential monitoring station, the service provided will include line security (i.e., the connecting lines are electronically supervised to detect evidence of tampering or malfunction). The level of protection for the alarmed area will include all points of probable entry (perimeter doors and accessible windows) with magnetic contacts and motion detectors positioned in the probable intruder paths from the probable points of entry to the classified information. In accordance with Federal Standard 809, no IDS sensors (magnetic contacts or vibration detectors) will be installed on GSA-approved security containers. CSA authorization on the alarm system description form is required in the following circumstances:

(ii) Access is sought by an individual who fails or refuses to comply with the established procedural requirements, including refusing to name a physician to receive medical records when required (see paragraph (f) of § 310.17) or to pay fees (see § 310.20). (2) Always explain to the individual the specific reason access has been refused and how he or she may obtain access. (c) Notifying the individual. Formal denials of access must be in writing and include as a minimum: (1) The name, title or position, and signature of a designated Component denial authority. (2) The date of the denial. (3) The specific reason for the denial, including specific citation to the appropriate sections of the Privacy Act (5 U.S.C. 552a) or other statutes, this part, DoD Component instructions, or CFR authorizing the denial; (4) Notice to the individual of his or her right to appeal the denial through the Component appeal procedure within 60 calendar days; and (5) The title or position and address of the Privacy Act appeals official for the Component. (d) DoD

Component appeal procedures. Establish internal appeal procedures that, as a minimum, provide for:

- (1) Review by the Head of the Component or his or her designee of any appeal by an individual from a denial of access to Component records.
- (2) Formal written notification to the individual by the appeal authority that shall:
 - (i) If the denial is sustained totally or in part, include as a minimum:
 - (A) The exact reason for denying the appeal to include specific citation to the provisions of the Act or other statute, this part, Component instructions or the CFR upon which the determination is based;
 - (B) The date of the appeal determination;
 - (C) The name, title, and signature of the appeal authority; and
 - (D) A statement informing the applicant of his or her right to seek judicial relief.
 - (ii) If the appeal is granted, notify the individual and provide access to the material to which access has been granted.
- (3) The written appeal notification granting or denying access is the final Component action as regards access.
- (4) The individual shall file any appeal from denial of access within no less than 60 calendar days of receipt of the denial notification.
- (5) Process all appeals within 30 days of receipt unless the appeal authority determines that a fair and equitable review cannot be made within that period. Notify the applicant in writing if additional time is required for the appellate review. The notification must include the reasons for the delay and state when the individual may expect an answer to the appeal.
- (e) Denial of appeals by failure to act. A requester may consider his or her appeal formally denied if the appeal authority fails:
 - (1) To act on the appeal within 30 days;
 - (2) To provide the requester with a notice of extension within 30 days; or
 - (3) To act within the time limits established in the Component's notice of extension (see paragraph (d)(5) of this section).
- (f) Denying access to OPM records held by the DoD Components.

- There is a widely held perception among manufacturers that consumers place a higher value on the design/functionality/aesthetics/usability of home IoT devices and a lesser value on security. As a result, manufacturers have invested more resources into creating designs that are feature-rich and user-friendly and less on cybersecurity. Maarten Bron said, 'Some research indicates that in general, consumers perceive value in functions/features of a device. For manufacturers, cybersecurity is knowledge/resource intense.' Panelist Rebecca Herold observed that 'manufacturers invest more into making the device look good and easy to use.' Bron said that manufacturers do not know where to start in terms of 'baking security' into home IoT devices, and cited NISTIRs and other European government agency documents as helpful references for manufacturers.

- Some workshop participants challenged the perception that consumers do not value security as much as they do usability and features. Panelist Jean Camp said, 'We're asking consumers to evaluate risk with no basis to do so. If you give people a default that offers privacy and security, they will choose to pay more. One study showed that consumers will pay on average \$17 more for a lightbulb that's private and secure.' Panelist Rebecca Herold added, 'Manufacturers assume that consumers don't care if security isn't built in because if they wanted it, they would ask for it. The problem with that belief is that most consumers assume security is already built in and turned on by default.'

- Manufacturers' delays in adding security features (encryption, adding more powerful processors, locked down interfaces, strong password usage) to home IoT devices may result in increased costs, design changes, or have an impact on functionality. Mark Haney gave an example of having to charge a smart watch battery daily versus weekly.

http://www.cnss.gov/Assets/pdf/cnssi_4009.pdf). These definitions are established and widely accepted Government definitions. No change is made to the rule. Comment: One comment stated that U.S. based systems are not adequately defined. Response: To further clarify terms, the term 'U.S. based' has been added to the definitions section (§ 236.2(n)). Comment: One comment recommended changing the definition of U.S. citizen to eliminate the phrase 'holding a U.S. passport,' and adding text on 'Green Cards.' Response: The recommendation to add 'U.S. citizen' to the definitions section is accepted and is added to § 236.2(o). For the purpose of the rule, a U.S. citizen includes a person born in the U.S. or naturalized. The recommendation to eliminate 'holding a U.S. passport' as part of the U.S. citizen definition is also accepted in the definition of 'U.S. citizen,' (see § 236.2(o)). Comment: One comment recommended changing the definition of GFI to a more descriptive term so as not to tie it to Government procurement. Response: The definition of GFI in the rule is applicable only to the DIB CS/IA program (see § 236.2(j)), and does not relate to any specific procurement activities. There is no indication that the use of this term has led to any confusion amongst the DIB participants. No change is made to the rule. Comment: Two comments dealt with aspects of sharing information that could ward against threats and improve Operational Security (OPSEC). Response: The purpose of the DIB CS/IA program is to enable cyber threat information sharing with DIB participants to improve operational security of DIB networks and information

systems. No change is made to the rule. Comment: One comment suggested replacing the phrase ·to use the GFI on non-U.S. based covered DIB systems,· with ·to reside on non-U.S. based covered DIB· in §-236.4(g). Response: After evaluation, the recommended change in terminology from ·use· to ·reside· does not provide additional technical clarity. No change is made to the rule. Comment: Two comments recommended the language be amended to include the words ·or as soon as practicable thereafter· following the word ·discovery· and expressed caution that less knowledgeable participants will be prone to over report which consumes scarce Government and industry resources and obscures the significant incidents (§-236.5(b)). (printed page 62434) Response: Timeliness in reporting cyber incidents involving covered defense information is an integral component of the DIB CS/IA program. The rule makes provisions for initial and follow-up reporting (§-236.5(b) and (c)). While the DIB CS/IA program is voluntary, cyber security encourages sharing information as quickly as possible to provide the clearest understanding of the cyber threat targeting DoD program information. This enables cyber threat information provided by DIB participants to be shared with other DIB participants and Government stakeholders on a timely basis. No change is made to the rule. Comment:

(4) Clearly mark a report containing information submitted in confidence as containing that information. When reports contain information pertaining to an individual, 5 U.S.C. 552a (also known as and referred to in this rule as ·The Privacy Act of 1974, as amended,·) permits the withholding of certain information from the individual in accordance with specific exemptions, which include authority to withhold release of information to the extent that the disclosure of the information would reveal the identity of a source who furnished the information to the USG under an express promise that the identity of the source would be held in confidence. (b) Reports to be submitted to the FBI. The contractor will promptly submit a written report to the nearest field office of the FBI regarding information coming to the contractor's attention concerning actual, probable, or possible espionage, sabotage, terrorism, or subversive activities at any of its locations. (1) An initial report may be made by phone, but it must be followed up in writing (e.g., email or formal correspondence), regardless of the FBI's disposition of the report. (2) The contractor will promptly notify the CSA when they make a report to the FBI and provide the CSA a copy of the written report. (c) Reports to be submitted to the CSA. ·(1) Adverse information. Contractors are required to report adverse information coming to their attention concerning any of their employees determined to be eligible for access to classified information, in accordance with this rule, SEAD 3, and CSA-provided guidance. Contractors will not make reports based on rumor or innuendo. (i) The termination of employment of an employee does not negate the requirement to submit this report. If a contractor employee is assigned to a USG location, the contractor will furnish a copy of the report and its final disposition to the USG security point of contact for that location. (ii) Pursuant to *Becker v. Philco*, 372 F.2d 771 (4th Cir. 1967), cert. denied 389 U.S. 979 (1967), and subsequent cases, a contractor may not be liable for defamation of an employee because of communications that are required of and made by a contractor to an agency of the United States under the requirements of this rule or under the terms of applicable contracts. (printed page 83324) (2) Suspicious contacts. Contractors will report information pertaining to suspicious contacts with employees determined to be eligible for access to classified information, and pertaining to efforts to obtain illegal or unauthorized access to the contractor's cleared facility by any means, including: (i) Efforts by any individual, regardless of nationality, to obtain illegal or unauthorized access to classified information.

The contingency plan protects resources, minimizes customer inconvenience, and identifies key staff, assigning specific responsibilities in the context of the recovery. Contingency plans are critical to protecting the availability, integrity, and security of data during unexpected adverse events. Contingency plans should consider not only how to respond to disasters such as fires and floods, but also how to respond to cyberattacks. Cyberattacks using malicious software, such as ransomware, may render an organization's data unreadable or unusable. In the event data is compromised by a cyberattack, restoring the data from backups may be the only option for recovering the data and restoring normal business operations. For example, the faulty software update by CrowdStrike made it impossible for health care systems worldwide to use their Windows-based systems. [607] There were many instances where surgical procedures and health care appointments were cancelled, schedules upended, and pharmacies were unable to fill prescriptions. Regulated entities need to make and implement contingency plans they would use when such events occur to enable themselves to get back to their core functions of providing or paying for health care. The Department and NIST have issued extensive guidance on contingency planning, including detailed descriptions of key activities,

sample questions for regulated entities to consider when standing up a contingency plan, and information on how the results of the risk analysis feed into contingency plans. [608] Unfortunately, many regulated entities have not implemented the required (printed page 955) planning and then have been unable to fully recover from ransomware attacks that bring down electronic systems that create, receive, maintain, or transmit ePHI. For example, a large health system that experienced a ransomware attack had to shut down services at multiple locations and encountered difficulties restoring those services. OCR's investigation indicated a potential failure to, among other things, implement contingency plans. [609] Such planning is crucial for maintaining the resilience of a regulated entity's health IT. To address these inadequacies in compliance and to protect the confidentiality, integrity, and availability of ePHI, the Department proposes to redesignate the standard for a contingency plan at 45 CFR 164.308(a)(7)(i) as proposed 45 CFR 164.308(a)(13)(i) , to add a paragraph heading to clarify the organization of the regulatory text, and to modify the regulatory text to clarify it. The modified standard, as proposed, would require a regulated entity to establish (and implement as needed) a written contingency plan, consisting of written policies and procedures for responding to an emergency or other occurrence, including, but not limited to, fire, vandalism, system failure, natural disaster, or security incident, that adversely affects relevant electronic information systems.

(Comment 187) Many comments state that lot codes are not currently used in tracking products at the distributor and retailer levels, and that requiring lot codes to be recorded by these entities would represent a large change in business practice. One comment states that only 10 percent of food distributors currently use lot numbers to track their food products. One comment states that its facility tested the proposed requirement to establish records of lot numbers in its daily operations and concluded that there would be an 80 percent loss in productivity as a result of the requirement. Another comment states that labor costs for unloading a truck at a distributor would increase by a factor of 15 under an exhaustive check of shipper and lot code information. The comment further states that a conservative estimate of the unloading costs would be a threefold increase in current costs if a less exhaustive spot check of the lot codes is required. Other comments illustrate the dramatic change in current business practices that would result from requiring lot codes to be included in records. However, several comments indicate that although the technology to maintain lot codes in bar code format does not currently exist, the industry is moving in that direction and such a requirement might be feasible in 5 to 7 years. (Response) In estimating the costs of the rule, FDA assumed that all required information provided for in the regulation represented only small deviations from current business practice. The comments received strongly suggest that the cost estimates for maintaining records on lot codes for distributors and retailers were substantially understated. The results reported by one comment of an experiment that tested the requirement in their daily operations indicated an 80 percent loss in productivity. Other estimates of the increase in labor costs that would result from this requirement ranged from three-fold to fifteen-fold. FDA revises the estimates of the costs to maintain records on lot codes by assuming an 80 percent loss in productivity for retailers and distributors from compliance with this provision. For other policy options included in this analysis as well as in the final rule, the requirement to establish and maintain records containing lot codes is relaxed to be consistent with current feasibility. 3. Records Retention Costs

Section 170.15 addresses how an OSA will achieve and maintain compliance with CMMC Level 1 Self-Assessment. The OSA must successfully implement the security requirements listed in § 170.14(c)(2) within their Level 1 CMMC Assessment Scope as described in § 170.19(b). Successful implementation requires meeting all objectives defined in NIST SP 800-171A for the corresponding CMMC Level 1 security requirements as outlined in the mapping table 1 to § 170.15(c)(1)(i). After implementation, the OSA must perform a self-assessment to verify the implementation and score themselves using the scoring methodology provided in § 170.24. All objectives must be met in order for a security requirement to be considered fully implemented; no security requirements may be placed on a POA&M for Level 1. The OSA must then input their results into SPRS as described in § 170.15(a)(1)(i) and submit an affirmation as described in § 170.22. In order to be eligible for a contract with a CMMC Level 1 Self-Assessment requirement, the OSA must have a Level 1 Self-Assessment and have submitted an affirmation. These activities must be completed annually. Section 170.16-CMMC Level 2 Self-Assessment and Affirmation Requirements Section 170.16 addresses how an OSA will achieve and maintain compliance with CMMC Level 2 Self-Assessment. The OSA must successfully implement the security requirements listed in § 170.14(c)(3) within its Level 2 CMMC Assessment Scope as described in § 170.19(c). Successful implementation requires meeting all

objectives defined in NIST SP 800-171A for the corresponding CMMC Level 2 security requirements. After implementation, the OSA must perform a self-assessment to verify the implementation and score themselves using the scoring methodology provided in § 170.24. All objectives must be met in order for a security requirement to be considered fully implemented; in some cases, if not all objectives are met, some security requirements may be placed on a POA&M as provided for in § 170.21. If the minimum score has been achieved and some security requirements are in a POA&M, the OSA has a Conditional Self-Assessment; if the minimum score has been achieved and no security requirements are in a POA&M, the OSA has a Final Self-Assessment. For Conditional Self-Assessments, a POA&M close-out must be conducted within 180 days as described in § 170.21(b). After both Conditional Self-Assessment and Final Self-Assessment, the OSA must input their results into SPRS as described in § 170.16(a)(1)(i) and submit an affirmation as described in § 170.22. In order to be eligible for a contract with a CMMC Level 2 Self-Assessment requirement, the OSA must have a Level 2 Conditional Self-Assessment or Level 2 Final Self-Assessment and have submitted an affirmation. The Level 2 Self-Assessment must be completed tri-annually and the affirmation must be completed annually.

Section 170.17 CMMC Level 2 Certification Assessment and Affirmation Requirements

, the Federal Food, Drug, and Cosmetic Act is referred to as ‘the act.’ Thus, when the regulation is quoted in this preamble, the term ‘the act’ will be used to refer to the Federal Food, Drug, and Cosmetic Act. However, in this preamble, we refer to the Federal Food, Drug, and Cosmetic Act as ‘the FD&C Act’ to distinguish it from the Bioterrorism Act.) Section 414(b) of the FD&C Act provides, in part, that the Secretary of Health and Human Services (the Secretary), may by regulation establish requirements regarding the establishment and maintenance, for not longer than 2 years, of records by persons (excluding farms and restaurants) who manufacture, process, pack, transport, distribute, receive, hold, or import food. The records that are required to be kept by these regulations are those needed by the Secretary for inspection to allow the Secretary to identify the immediate previous sources and immediate subsequent recipients of food, including its packaging, to address credible threats of serious adverse health consequences or death to humans or animals. Section 306(d) of the Bioterrorism Act provides that the Secretary ‘shall’ issue regulations establishing recordkeeping requirements under section 414(b) of the FD&C Act no later than 18 months after enactment of the Bioterrorism Act, that is, by December 12, 2003. In addition, the Bioterrorism Act adds a new section 414(a) to the FD&C Act (printed page 71563) that provides records inspection authority to FDA. Section 414(a) of the FD&C Act provides that, if the Secretary has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals, persons who manufacture, process, pack, distribute, receive, hold, or import food must provide access to records related to the food that are needed to assist the Secretary in determining whether the food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals. Section 306 of the Bioterrorism Act also amends section 704(a) of the FD&C Act (21 U.S.C. 374(a)) to authorize FDA inspections of all records and other information described in section 414 of the FD&C Act, when the Secretary has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals. In addition, section 306(c) of the Bioterrorism Act amends section 301 of the FD&C Act (21 U.S.C. 331

(C) From subsection (d) because these provisions concern individual access to and amendment of certain records contained in this system, including law enforcement, counterterrorism, investigatory, and intelligence records. Compliance with these provisions could alert the subject of an investigation of the fact and nature of the investigation, and/or the investigative interest of intelligence or law enforcement agencies; compromise sensitive information related to national security; interfere with the overall law enforcement process by leading to the destruction of evidence, improper influencing of witnesses, fabrication of testimony, and/or flight of the subject; could identify a confidential source or disclose information which would constitute an unwarranted invasion of another's personal privacy; reveal a sensitive investigative or intelligence technique; or constitute a potential danger to the health or safety of law enforcement personnel, confidential informants, and witnesses. Amendment of these records would interfere with ongoing counterterrorism, law enforcement, or intelligence investigations and analysis activities and impose an impossible administrative burden by requiring investigations, analyses, and reports to be continuously reinvestigated and revised. (D) From subsection (e)(1) because it is not always possible to determine what information is relevant and necessary to complete an identity comparison between the individual seeking access and a known or suspected terrorist. Also, because DoD and other agencies may not always know what information about an encounter with a known or suspected terrorist will be

relevant to law enforcement for the purpose of conducting an operational response. (E) From subsection (e)(2) because application of this provision could present a serious impediment to counterterrorism, law enforcement, or intelligence efforts in that it would put the subject of an investigation, study, or analysis on notice of that fact, thereby permitting the subject to engage in conduct designed to frustrate or impede that activity. The nature of counterterrorism, law enforcement, or intelligence investigations is such that vital information about an individual frequently can be obtained only from other persons who are familiar with such individual and his/her activities. In such investigations, it is not feasible to rely upon information furnished by the individual concerning his own activities. (F) From subsection (e)(3) to the extent that this subsection is interpreted to require DoD to provide notice to an individual if DoD or another agency receives or collects information about that individual during an investigation or from a third party. Should this subsection be so interpreted, exemption from this provision is necessary to avoid impeding counterterrorism, law enforcement, or intelligence efforts by (printed page 14811)

is a DoD information collection used to conduct its monitoring and oversight of contractors. OMB Control Number 0704-0567, DoD Contract Security Classification Specification, this collection is used by both DoD and agencies which have an industrial security agreement with DoD. OMB Control Number 0704-0573, Defense Information System for Security, is a DoD automated system for personnel security, providing a common, comprehensive medium to record, document, and identify personal security actions within DoD including submitting adverse information, verification of security clearance status, requesting investigations, and supporting continuous evaluation activities. It requires personal data collection to facilitate the initiation, investigation and adjudication of information relevant to DoD security clearances and employment suitability determinations for active duty military, civilian employees and contractors seeking such credentials. OMB Control Number 0704-0496, Joint Personnel Adjudication System, an information system which requires personal data collection to facilitate the initiation, investigation and adjudication of information relevant to DoD security clearances and employment suitability determinations for active duty military, civilian employees and contractors seeking such credentials. OMB Control Number 0704-0579, Certificate Pertaining to Foreign Interests SF (328) which is a common form which can be used by all CSAs. OMB Control Number 3150-0047, 10 CFR part 95, Facility Security Clearance and Safeguarding of National Security Information and Restricted Data, is an NRC information collection used to obtain an FCL and for safeguarding Secret and Confidential National Security Information and Restricted Data. Licensees under 10 CFR part 95 fall within two categories, those who possess, use or transmit classified matter at their site or a cleared contractor site, and those licensees and contractors who only need access to classified matter at a government or appropriately cleared non-government site. OMB Control Number 1910-1800, Security Package, is a DOE information collection used by DOE to conduct its monitoring and oversight of contractors under its security cognizance and to provide a platform for other CSAs, GCAs or prime contractors to verify whether a contractor has a DOE-granted FCL. Executive Order 13132, "Federalism" E.O. 13132 establishes certain requirements that an agency must meet when it promulgates a final rule (and subsequent final rule) that imposes substantial direct requirement costs on (printed page 83312) State and local governments, preempts State law, or otherwise has Federalism implications. This final rule will not have a substantial effect on State and local governments. List of Subjects in 32 CFR Part 117 Classified information; Government contracts; USG contracts National Industrial Program (NISP); Prime contractor Subcontractor Accordingly, the Department of Defense amends chapter I of title 32 of the CFR

In addition to proposing the elimination of default passwords, the Department proposes a specific requirement for a regulated entity to deploy MFA in the implementation specification for MFA at proposed 45 CFR 164.312(f)(2)(ii). We propose to expressly require MFA, as recommended by NCVHS, because it increases security by ensuring that a compromise of a single credential does not allow access to unauthorized users. [775] MFA is an effective way to reduce the risk of brute force attacks and to increase the cost of such attack, making such an attack less appealing to intruders. [776] Further, deployment of MFA aligns with the Department's essential CPGs for Email Security and Multifactor Authentication because use of MFA would be applicable to email access and protect assets connected to the internet. [777] Accordingly, proposed 45 CFR 164.312(f)(2)(ii)(A) would require a regulated entity to deploy MFA to all technology assets in its relevant electronic information systems to verify that the person seeking access to its relevant electronic information system is the user that the person claims to be. A regulated entity should deploy MFA to all technology assets in its relevant electronic information systems in a manner consistent with its

risk analysis. MFA allows for the use of different categories of factors as described earlier. A decision by a regulated entity to use specific factors during specific circumstances where MFA is deployed will be dependent upon the risks to ePHI identified by the regulated entity and the ability of technology to use such factors to authenticate specific users. For example, certain behavioral characteristics may not satisfy current standards for MFA; however, the Department anticipates that it may be reasonable and appropriate in the future for a regulated entity to adopt a solution where users provide such characteristics as one of the factors. Additionally, a regulated entity may identify varying levels of risk posed by its technology assets and elect to deploy MFA in different ways to address the risk posed by each asset. For example, consistent with its risk analysis, a regulated entity may choose to deploy a single sign-on (SSO) authentication solution using MFA to allow users to access multiple local applications, while also requiring users to authenticate using MFA to access certain cloud-based services. This proposed implementation specification generally is consistent with ASTP/ONC's Health Data, Technology, and Interoperability: Patient Engagement, Information Sharing, and Public Health Interoperability (HTI-2) NPRM's proposed revisions to the MFA criterion requiring certified health IT to support authentication, through multiple elements, of the user's identity, according to today's standards such as those recommended by NIST, and enable user to configure, enable, and disable the MFA capabilities. [778]

3.1.3 Authorization Vulnerability (CWE-284) Description Authorization is the process of assigning correct system permissions to an authenticated entity.

5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) The specific sections of 5 U.S.C. 552 a from which the system is exempt are 5 U.S.C. 552a(c)(3) , (d)(1) through (4), (e)(1), (e)(4)(G), (H), (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons. (A) From subsection (c)(3), as to grant access to an accounting of disclosures as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation or prosecutive interest by DLA or other agencies. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or making witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence. (B) From 5 U.S.C. 552a(d)(1) through (4) and (f) , as providing access to records of a civil or administrative investigation, and the right to contest the contents of those records and force changes to be made to the information contained therein, would interfere seriously with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow: Interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach to satisfy any Government claim arising from the investigation or proceeding. (C) From 5 U.S.C. 552a(e)(1) , as it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From 5 U.S.C. 552a(e)(4)(G) and (H) , as this system of records is compiled for law enforcement purposes and is exempt from the access provisions of 5 U.S.C. 552a(d) and (f) . (E) From 5 U.S.C. 552a(e)(4)(I) , as to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. DLA will, nevertheless, continue to publish such a notice in broad generic terms as is its current practice. (6) System identifier and name. S510.30 (Specific/General Exemption), Freedom of Information Act/Privacy Act Requests and Administrative Appeal Records. (i) Exemption.

<!-- image --> ## NIST Cybersecurity White Paper NIST CSWP 28 ## Security Segmentation in a Small Manufacturing Environment Dr. Michael Powell National Cybersecurity Center of Excellence National Institute of Standards and Technology John Hoyt Aslam Sherule Dr. Lynette Wilcox The MITRE Corporation This publication is available free of charge from: <https://doi.org/10.6028/NIST.CSWP.28> April 6 , 2023 <!-- image --> Certain commercial entities, equipment, or materials may be identified in this document in order to describe an experimental procedure or concept adequately. Such identification is not intended to imply recommendation or

endorsement by the National Institute of Standards and Technology (NIST), nor is it intended to imply that the entities, materials, or equipment are necessarily the best available for the purpose.

NIST Technical Series Policies Copyright, Fair Use, and Licensing Statements NIST Technical Series Publication Identifier Syntax ## Publication History Approved by the NIST Editorial Review Board on 2023-03-30 ## How to Cite this NIST Technical Series Publication: Powell M, Hoyt J, Sherule A, Wilcox L (2023) Security Segmentation in a Small Manufacturing Environment. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Cybersecurity White Paper (CSWP) NIST CSWP 28. <https://doi.org/10.6028/NIST.CSWP.28> ## Author ORCID iDs Dr. Michael Powell: 0000-0002-3922-7435 John Hoyt: 0000-0002-0783-7036 Aslam Sherule: 0000-0002-2003-3817 Dr. Lynette Wilcox: 0000-0003-1246-6505 ## Contact Information manufacturing_nccoe@nist.gov National Institute of Standards and Technology Attn: Applied Cybersecurity Division, Information Technology Laboratory 100 Bureau Drive (Mail Stop 2000) Gaithersburg, MD 20899-2000 All comments are subject to release under the Freedom of Information Act (FOIA). ## Abstract Manufacturers are increasingly targeted in cyber-attacks.

at 25212) may be true for suppliers in other packaging segments, but is simply incorrect when it comes to the cartonboard segment of the industry. The comment states that packaging companies in that segment will find it more expedient to keep records on all materials—both outer packaging and contact substances—rather than to document only the food contact materials, because many of the same materials can be used for both purposes, and it would be prohibitively expensive to segregate these uses. The comment notes that this would result in a recordkeeping requirement for nearly all facilities that manufacture packaging and packaging components, and all of their suppliers, if FDA retains the proposed approach. One comment states the inclusion of “immediate food packaging” and “food contact substances” in the definition of “food” creates a difficult and (printed page 71584) unnecessary compliance effort throughout the supply chain. The comment suggests that FDA remove the requirement to establish and maintain records on “immediate food packaging” and “food contact substances” after such materials are either accompanying or affixed to the food, thus eliminating duplicative tracking and burdensome paperwork. If records are kept on the food, the comment states that those same records could be used to trace the packaging and labeling materials to the farm and point of initial contact with the food. From there, the material's original manufacturing/processing facility can be identified, where detailed records on the immediate subsequent transporter and recipient (likely the farm) will be maintained according to the regulations. (Response) FDA agrees with these comments in part. FDA is finalizing the definition of “food” as proposed and is not excluding food contact substances from the definition. As discussed in the following paragraphs and provided in §§ 1.327(i) and (j) of this final rule, however, FDA is using our discretion to exclude specified persons and activities from recordkeeping requirements for packaging and food contact substances. These comments raise the question of what Congress intended “food” to mean for purposes of recordkeeping and access. In construing the recordkeeping and access provisions of the Bioterrorism Act, FDA is confronted with two questions. First, has Congress directly spoken to the precise question presented (Chevron step one)? *Chevron, U.S.A., Inc. v. NRDC, Inc.*, 467 U.S. 837, 842 (1984). To find no ambiguity, Congress must have focused directly on the question presented and have articulated clearly its intention. *Young v. Community Nutrition Institute*, 476 U.S. 974, 980 (1986). If Congress has spoken directly and plainly, the agency must implement Congress's unambiguously expressed intent. *Chevron*, 467 U.S. at 842-843. If, however, the Bioterrorism Act is silent or ambiguous as to the meaning of “food,” FDA may define “food” in a reasonable fashion (Chevron step two). *Chevron*, 467 U.S. at 842-843; *FDA v. Brown & Williamson Tobacco Corp.*

Through its Internet Policy Task Force, the Department intends to recommend public policies and private-sector norms that can markedly improve the overall cybersecurity posture of private sector infrastructure operators, software and service providers, and users outside the critical infrastructure and key resources realm and of their customers. Cybersecurity and Commerce: Due to the Department's over-arching responsibility to advance the nation's commercial interests, the Task Force is focused on the cybersecurity challenges facing businesses and consumers that use the Internet. The nation's e-commerce interests are significant. Growth in online sales and expanding use of the Internet are creating new jobs and contributing directly to our economic recovery. Businesses of all sizes increasingly use the Internet to order and track inventory, sell products and services, store financial and other proprietary information, and interact with their customers. These shifts in business practices and other measures have led to a greatly increased average growth in productivity over the last fifteen years. [7] Over the long term, such growth benefits our

global competitiveness. [8] Taking into account both business-to-consumer and business-to-business transactions, online commerce in 2007 accounted for more than \$3 trillion in revenue for U.S. companies. [9] In the business-to-consumer e-commerce space, the United States economy enjoyed an increase in revenue of more than 500 percent between 1999 and 2007. [10] Even during the recent economic downturn, the economic benefits provided by the Internet economy increased. In 2009, online retail sales grew 2.0 percent to reach \$134.9 billion, [11] while total retail sales fell 7 percent in that same year. Also in 2009, U.S. mobile commerce sales grew more than 200 percent compared to the previous year, reaching \$1.2 billion. [12] Analysts expect this growth to continue in 2010, projecting \$2.4 billion in mobile commerce. [13] Notwithstanding this consistent, impressive growth, companies continue to face significant challenges in their ability to appropriately protect their computer systems, secure their proprietary, personal, and financial information, and safeguard the integrity of business and other transactions that they conduct over the Internet. Reports of significant, persistent, individual cyber intrusions occur on a regular basis, as do reports of widespread, untargeted cyber incidents. The Cyberspace Policy Review described a coordinated attack in 49 cities on more than 130 automated teller machines in 2008, as well as a single 2007 data breach at one company that resulted in more than 45 million compromised consumer financial accounts. [14]

means the act of eliminating the functional capabilities and inherent military design features from DoD personal property. Methods and degree range from removal and destruction of critical features to total destruction by cutting, tearing, crushing, mangling, shredding, melting, burning, etc. (2) Export-controlled items means items subject to the Export Administration Regulations (EAR) (15 CFR parts 730-774) or the International Traffic in Arms Regulations (ITAR) (22 CFR parts 120-130). The term includes: (i) Defense items, defined in the Arms Export Control Act, 22 U.S.C. 2778(j)(4)(A) , as defense articles, defense services, and related technical data, etc.; and (ii) Items, defined in the EAR as ·commodities,· ·software,· and ·technology,· terms that are also defined in the EAR, 15 CFR 772.1 . (3) Ineligible transferees means individuals, entities, or countries: (i) Excluded from Federal programs by the General Services Administration as identified in the Excluded Parties Listing System (EPLS) (<https://www.epls.gov/>); (ii) Delinquent on obligations to the U.S. Government under surplus sales contracts; (iii) Designated by the Department of Defense as ineligible, debarred, or suspended from defense contracts; or (iv) Subject to denial, debarment, or other sanctions under export control laws and related laws and regulations, and orders (printed page 52144) administered by the Department of State, the Department of Commerce, the Department of Homeland Security, or the Department of the Treasury. (4) Scrap means property that has no value except for its basic material content. For purposes of demilitarization, scrap is defined as recyclable waste and discarded materials derived from items that have been rendered useless beyond repair, rehabilitation, or restoration such that the item's original identity, utility, form, fit, and function have been destroyed. Items can be classified as scrap if processed by cutting, tearing, crushing, mangling, shredding, or melting. Intact or recognizable components and parts are not ·scrap.· (5) Serviceable or usable property means property with potential for reutilization or sale ·as is· or with minor repairs or alterations. (b) Inventory disposal schedules. Unless disposition instructions are otherwise included in this contract, the Contractor shall complete SF 1428, Inventory Schedule B, within the Plant Clearance Automated Reutilization Screening System (PCARSS). Information on PCARSS can be obtained from the plant clearance officer and at <http://www.dcmil/ITCSO/CBT/PCARSS/index.cfm> . (1) The SF 1428 shall contain the following: (i) If known, the applicable Federal Supply Code (FSC) for all items, except items in scrap condition. (ii) If known, the manufacturer name for all aircraft components under Federal Supply Group (FSG) 16 or 17 and FSCs 2620, 2810, 2915, 2925, 2935, 2945, 2995, 4920, 5821, 5826, 5841, 6340, and 6615.

A fundamental problem with log management that occurs in many organizations is effectively balancing a limited quantity of log management resources with a continuous supply of log data. Log generation and storage can be complicated by several factors, including a high number of log sources; inconsistent log content, formats, and timestamps among sources; and increasingly large volumes of log data. Log management also involves protecting the confidentiality, integrity, and availability of logs. Another problem with log management is ensuring that security, system, and network administrators regularly perform effective analysis of log data. This publication provides guidance for meeting these log management challenges. - GLYPH<c=31;font=/APONEK+Webdings> Antimalware Software. The most common form of antimalware software is antivirus software, which typically records all instances of detected malware, file and system disinfection attempts, and file

quarantines. 3 Additionally, antivirus software might also record when malware scans were performed and when antivirus signature or software updates occurred. Antispyware software and other types of antimalware software (e.g., rootkit detectors) are also common sources of security information. - GLYPH<c=31;font=/APONEK+Webdings> Intrusion Detection and Intrusion Prevention Systems. Intrusion detection and intrusion prevention systems record detailed information on suspicious behavior and detected attacks, as well as any actions intrusion prevention systems performed to stop malicious activity in progress. Some intrusion detection systems, such as file integrity checking software, run periodically instead of continuously, so they generate log entries in batches instead of on an ongoing basis. 4 - GLYPH<c=31;font=/APONEK+Webdings> Remote Access Software. Remote access is often granted and secured through virtual private networking (VPN).

From the NIST SP 800-172 Rev 3 Final Public Draft: Information includes CUI and metadata that contains security attributes associated NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 with information. Integrity-checking mechanisms including parity checks, cyclical 2097

3.3.4 Access Control for Applications... 3.3.4 Access Control for Applications Different types of remote access architectures offer different levels of granularity for application access control.

At the request of a FOIA requester, records provided under this part shall be authenticated with an appropriate seal whenever necessary to fulfill an official Government or other legal function. This service is in addition to that required under the FOIA and is not included in the FOIA fee schedule. The DoD Components may charge a fee of \$5.20 for each authentication. (j) Combatant commands. (1) The Combatant Commands are placed under the jurisdiction of the OSD, instead of the administering Military Department or the Chairman of the Joint Chiefs of Staff, for the purpose of administering the DoD FOIA Program. This policy represents an exception to the policies directed in DoD Directive 5100.3; it authorizes and requires the Combatant Commands to process FOIA requests in accordance with 32 CFR part 285 and this part. When requested, the Combatant Commands shall forward directly to the DFOIPO all correspondence associated with the appeal of an initial denial for records under the provisions of the FOIA. The Combatant Commands will advise requesters that they have the right to appeal any adverse determinations to the DFOIPO. (2) The Combatant Commands shall comply with all provisions of this part that apply to the DoD Components except the appointments of an appellate authority and a FOIA Public Liaison. (k) Security clearances and access for FOIA personnel. Due to the nature of their duties and responsibilities, FOIA personnel need access to all records requested through their respective offices, regardless of the sensitivity or classification of the information. The DoD Components shall ensure FOIA personnel have the appropriate clearances and accesses to perform their duties. (l) Use of Contractors in FOIA Administration. According to DoD Instruction 1100.22 and OMB Circular A-76, there are certain functions, known as inherently governmental activities that cannot be outsourced to a contractor. Since some of the functions of the FOIA Officer are inherently governmental, the DoD Components shall be careful not to outsource those FOIA functions that are inherently governmental. Primarily, activities which require the exercise of substantial discretion in applying government authority or in making decisions for the government are inherently governmental. Inherently governmental FOIA functions include: (1) Formulating and/or approving FOIA policies and procedures. (2) Making final determinations regarding whether to treat incoming correspondence as a FOIA or Privacy Act request. (3) Deciding any issues regarding the scope or interpretation of the request. (4) Determining the appropriateness of claimed exemptions. (5) Approving the approach taken in negotiations/discussions with the requester. (6) Deciding administrative appeals. (7) Conducting final review of all outgoing correspondence, memoranda, and release packages. (8) Drafting court documents for filing in FOIA lawsuit in which the government's legal strategy and affirmative defense are determined.

Moreover, this proposal is consistent with guidance issued by HHS and NIST for implementing this standard and associated implementation specifications. For example, in guidance issued in 2005, we explained that regulated entities must identify workforce members who need access to ePHI to carry out their duties. [545] For each workforce member or job function, the regulated entity must identify the ePHI that is needed, when it is needed, and make reasonable efforts to control access to the ePHI, a concept generally referred to as role-based access (i.e., authorizing access to ePHI only when such access is appropriate based on the workforce member's role). [546] This also includes identification of the computer systems and applications that provide access to the ePHI. A regulated entity must provide only the minimum necessary access to ePHI that is required for

a workforce member to do their job. [547] As described in HHS guidance, access authorization is the process of determining whether a particular user (or a computer system) has the right, consistent with their function, to carry out a certain activity, such as reading a file or running a program. [548] Implementation may vary among regulated entities, depending on the size and complexity of their workforce, and their electronic information systems that contain ePHI. For example, in a small medical practice, all staff members may need to access all ePHI in their information systems because each staff member may perform multiple functions. In this case, the regulated entity would document the reasons for implementing policies and procedures that permit this type of global access. If the documented rationale is reasonable and appropriate, this may be an acceptable approach. The implementation specification provision for authorization and/or supervision provides the necessary checks and balances to ensure that all members of the workforce have appropriate access (or, in some cases, no access) to ePHI. NIST guidance provides descriptions of key activities and sample questions for regulated entities implementing this implementation specification. [549] To implement procedures for the authorization and/or supervision of workforce members who work with ePHI or in locations where it might be accessed, the guidance advises regulated entities to consider whether chains of command and lines of authority have been established, as well as the identity and roles of supervisors. A regulated entity also should establish clear job descriptions and responsibilities, which includes defining roles and responsibilities for all job functions; assigning appropriate levels of security oversight, training, and access; and identifying in writing who has the business need and who has been granted permission to view, alter, retrieve, and store ePHI and at what times, under what circumstances, and for what purposes. [550]

From subsections (c)(3) and (d) because the exemption is needed to encourage those who know of exceptional medical or educational conditions or family maltreatments to come forward by protecting their identities and to protect such sources from embarrassment or recriminations, as well as to protect their right to privacy. It is essential that the identities of all individuals who furnish information under an express promise of confidentiality be protected. Granting individuals access to information relating to criminal and civil law enforcement, as well as the release of certain disclosure accounting, could interfere with ongoing investigations and the orderly administration of justice, in that it could result in the concealment, alteration, destruction, or fabrication of information; could hamper the identification of offenders or alleged offenders and the disposition of charges; and could jeopardize the safety and well being of parents and their children. Exempted portions of this system also contain information considered relevant and necessary to make a determination as to qualifications, eligibility, or suitability for Federal employment and Federal contracts, and that was obtained by providing an express or implied promise to the source that his or her identity would not be revealed to the subject of the record. (6) System identifier and name. F036 AF PC A, Effectiveness/Performance Reporting System. (i) Exemption. Evaluation material used to determine potential for promotion in the Military Services (Brigadier General Selectee Effectiveness Reports and Colonel and Lieutenant Colonel Promotion Recommendations with close out dates on or before January 31, 1991) may be exempt pursuant to 5 U.S.C. 552a(k)(7) , but only to the extent that the disclosure of such material would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(7) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(4)(H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(7) . (iii) Reasons. (A) From subsection (c)(3) because making the disclosure accounting available to the individual may compromise express promises of confidentiality by revealing details about the report and identify other record sources, which may result in circumvention of the access exemption. (B) From subsection (d) because individual disclosure compromises express promises of confidentiality conferred to protect the integrity of the promotion rating system. (C) From subsection (e)(4)(H) because of and to the extent that portions of this record system are exempt from the individual access provisions of subsection (d). (D) From subsection (f) because of and to the extent that portions of this record system are exempt from the individual access provisions of subsection (d). (7) System identifier and name. F036 AFDP A, Files on General Officers and Colonels Assigned to General Officer Positions. (i) Exemption.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management,

administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. 3.10. MAYO 3.10. MAYO

The Department's proposal would also require that the procedures for contingency operations proposed at 45 CFR 164.310(a)(2)(i) support the regulated entity's contingency plan, instead of the current requirement specifying that the procedures support the restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency. [647] This proposal would align the implementation specification for contingency operations with the standard for contingency planning at proposed 45 CFR 164.308(a)(13)(i) by specifically ensuring that the written policies and procedures support the required contingency plan. It also would avoid duplicating the implementation specification for disaster recovery planning at proposed 45 CFR 164.308(a)(13)(ii)(D) , which would require a regulated entity to address the restoration of lost data and systems in the disaster recovery plan component of its contingency plan. We propose to modify 45 CFR 164.310(a)(2)(ii) to clarify that the written policies and procedures that constitute the facility security plan must apply to all of the regulated entity's facilities and equipment contained within those facilities. The Department proposes to retitle the implementation specification for access control and validation procedures at 45 CFR 164.310(a)(2)(iii) as ·Access management and validation procedures· and to require regulated entities to establish and implement written procedures to both authorize and manage a person's role-based access to facilities. In the implementation specification for maintenance records, the Department proposes at 45 CFR 164.310(a)(2)(iv) , to change the provision heading to ·Physical maintenance records· and to add security cameras to the list of examples of physical security components about which a regulated entity is required to implement written policies and procedures to document repairs and modifications. Both proposals are consistent with and recognize the evolution of the role that technology plays in managing and granting physical access to facilities. Consistent with our proposals to add maintenance requirements where we believe it is necessary for regulated entities to review, test, and modify their security measures on a particular cadence, we also propose to add an implementation specification for maintenance at proposed 45 CFR 164.310(a)(2)(v) . The maintenance provision would require that, for each facility, a regulated entity review and test its written policies and procedures at least once every 12 months, and to modify those policies and procedures as reasonable and appropriate based on that review. c. Section 164.310(b)(1)-Standard: Workstation Use and Section 164.310(c)-Standard: Workstation Security Further, in the standards for workstation use and workstation security at 45 CFR 164.310(b) (redesignated as proposed 45 CFR 164.310(b)(1) and (c)

ncidents must be communicated to the personnel defined below: 8. Details of cybersecurity events will be shared with ICS-CERT 15 to help secure the organization, including helping secure the industry. The Department of Homeland Security Cybersecurity and Infrastructure Security Agency (CISA) provides services for manufacturers to report cybersecurity events.

Safeguarding Covered Defense Information and Cyber Incident Reporting, requires defense contractors and subcontractors to provide ·adequate security· to process, store or transmit CUI on information systems or networks, and to report cyber incidents that affect these systems or networks. The clause states that to provide adequate security, the contractor shall implement, at a minimum, the security requirements in ·National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 Rev 2, Protecting CUI in Nonfederal Systems and Organizations.· Contractors are also required to flow down DFARS clause 252.204-7012 to all subcontracts that involve CUI. However, neither FAR 52.204-21 nor DFARS 252.204-7012, provide for DoD verification of a contractor's implementation of basic safeguarding requirements specified in FAR 52.204-21 nor the security requirements specified in DFARS 252.204-7012 which requires implementation of NIST SP 800-171 Rev 2 prior to contract award. Instead, DFARS clause 252.204-7012 requires prospective contractors or subcontractors to self-attest upon submission of their offer that they have implemented or will implement NIST SP 800-171 Rev 2. Findings from DoD Inspector General report (DODIG-2019-105 ·Audit of Protection of DoD CUI on Contractor-Owned Networks and Systems·) indicate that DoD contractors did not consistently implement mandated system security requirements for safeguarding CUI and recommended that DoD take steps to assess a contractor's ability to protect this information. The report emphasizes that malicious actors can exploit the vulnerabilities of contractors' networks and systems and exfiltrate information related to some of the Nation's most valuable advanced defense technologies. Due to these shortcomings and the associated risks to national security, the

Department developed the Cybersecurity Maturity Model Certification (CMMC) Program to assess contractor and subcontractor implementation of DoD's required cybersecurity standards. The Cybersecurity Maturity Model Certification (CMMC) Program verifies compliance with DoD cyber protection standards by defense contractors and subcontractors. It is designed to protect sensitive unclassified information that is shared by the Department with its contractors and subcontractors. The program incorporates a set of cybersecurity requirements into acquisition contracts and provides the Department increased assurance that contractors and subcontractors are meeting these requirements. The CMMC Program has three key features: Tiered Model: CMMC requires that companies implement cybersecurity requirements at progressively advanced levels, depending on the type and sensitivity of the information. The (printed page 89103) program also sets forth the process for information flow down to subcontractors. Assessment Requirement: CMMC assessments allow the Department to verify the implementation of cybersecurity requirements. Implementation through Contracts:

- Hypervisor host user account management - Hypervisor host authentication and access control - Routine administration of Host OS (e.g., keeping patches current) - Routine administration of Guest OS - Security of Guest OSs running on VMs - Security of Applications/Services running on VMs Configuration changes, module version changes, and patches affect the content of the hypervisor platform components such as BIOS, hypervisor kernel, and back-end device drivers running in the kernel. To ensure that each of these components that are part of the hypervisor stack can be trusted, it is necessary to check their integrity through a hardware-rooted attestation scheme that provides assurance of boot integrity. Checking integrity is done by cryptographically authenticating the hypervisor components that are launched. This authentication verifies that only authorized code runs on the system. Specifically, in the context of the hypervisor, the assurance of integrity protects against tampering and low-level targeted attacks such as root kits. If the assertion of integrity is deferred to a trusted third party that fulfills the role of trusted authority, the verification process is known as trusted attestation . Trusted attestation provides assurance that the code of the hypervisor components has not been tampered with. In this approach, trust in the hypervisor's components is established based on trusted hardware. In other words, a chain of trust from hardware to hypervisor is established with the initial component called the root of trust . This service can be provided by a hardware/firmware infrastructure of the hypervisor host that supports boot integrity measurement and the attestation process. In short, a measured launch environment (MLE) is needed in the hypervisor host.

During the processing of a Freedom of Information Act (FOIA) and Privacy Act (PA) request, exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those ·other· systems of records are entered into this system, the Inspector General, DoD, claims the same exemptions for the records from those ·other· systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (6) System identifier and name. CIG-21, Congressional Correspondence Tracking System. (i) Exemption. During the processing of a Congressional inquiry, exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those ·other· systems of records are entered into this system, the Inspector General, DoD, claims the same exemptions for the records from those ·other· systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (ii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions

have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information (printed page 14802)

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 ENHANCED SECURITY REQUIREMENT
ORGANIZATION-DEFINED PARAMETER 03.14.14E [Assignment: organization-defined safeguards] 03.14.15E
[Assignment: organization-defined system components and services] 03.14.16E [Selection (one or
more): upon end of session of use; at [Assignment: organization-defined frequency]] 03.14.17E
[Assignment: organization-defined systems or system components] 03.14.18E [Assignment:
organization-defined personnel or roles] 03.14.19E [Assignment: organization-defined compromise
indicators] 03.14.20E [Assignment: organization-defined personnel or roles] 03.14.21E [Assignment:
organization-defined activities that trigger alerts] 03.15.01E [Assignment: org

Given the dynamic nature of cyber threats, it is important for even the most sophisticated commercial entities to be vigilant. One of the best ways to improve defensive capabilities is for good actors to share important information with each other and with appropriate authorities. Yet in our listening sessions, we heard comments that questioned whether enough is being done on this front. Security breach legislation has gone into effect in many states. [19] Nonetheless, our current perception is that for many reasons firms that have experienced cyber intrusions or attacks either do not know with whom to share that information or are reluctant to share. In the immediate aftermath of a recent, high-profile cyber incident, we heard a variation on this theme. Reportedly, even the most sophisticated small and medium-sized firms are daunted by how complicated it can be to share information on the incidents they have suffered. A successful, targeted intrusion might involve exploitation of a technology vulnerability, loss of customer information, theft of intellectual property or other digital assets, and loss of financial information. Such an exploit might be executed and addressed in a matter of minutes or hours, yet reporting the incident and the losses to the proper officials could consume numerous man-hours, with business owners unsure whether the expenditure of that amount of time yields any benefit to the business. We seek comment on whether there is adequate awareness of information sharing programs. Are existing information sharing mechanisms adequately-resourced but under-utilized? If so, what deters their use? How can the state of affairs be improved? Are there parts of the business community that do not know the governmental points-of-contact, US-CERT, to report, share information on, and seek guidance regarding cybersecurity incidents? If there are parts of the business community that are unaware of available resources, which parts are they and what steps might help to raise their awareness? Even among that who are aware of the resources and mechanisms available for information sharing and assistance, is there a reluctance to use them? If so, why? Does the government adequately assist businesses in the throes or in the aftermath of a cyber incident? Should the government create a cybersecurity service center to assist the business community in implementing protection measures, sharing information about cyber threats reported by businesses and other sources, and dealing with cybersecurity incidents that occur? What other steps can be taken to improve situational awareness across the business sector? 3. Web Site and Component Security Increasingly, malware and other malicious content are able to infect computers and other user access devices (e.g.,

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 159 [DOD-2008-OS-0125/RIN 0790-AI38] AGENCY: Office of the Under Secretary of Defense for Acquisition, Technology, and Logistics, DoD. ACTION: Final rule. SUMMARY: This Rule establishes policy, assigns responsibilities and provides procedures for the regulation of the selection, accountability, training, equipping, and conduct of personnel performing private security functions under a covered contract during contingency operations, combat operations or other significant military operations. It also assigns responsibilities and establishes procedures for incident reporting, use of and accountability for equipment, rules for the use of force, and a process for administrative action or the removal, as appropriate, of PSCs and PSC personnel. For the Department of Defense, this Rule supplements DoD Instruction 3020.41, ·Contractor Personnel Authorized to

Accompany the U.S. Armed Forces, which provides guidance for all DoD contractors operating in contingency operations. This Rule was published as an Interim Final Rule on July 17, 2009 because there was insufficient policy and guidance regulating the actions of DoD and other governmental PSCs and their (printed page 49651) movements in operational areas. This Rule ensures compliance with laws and regulations pertaining to Inherently Governmental functions, and ensures proper performance by armed contractors. DATES: Effective Date: This rule is effective September 12, 2011. FOR FURTHER INFORMATION CONTACT: Chris Mayer, Director, Armed Contingency Contractor Policy and Programs, Office of the Deputy Assistant Secretary of Defense (Program Support), (571) 232-2509. SUPPLEMENTARY INFORMATION: The publication of this Rule is required to meet the mandate of Section 862 of the 2008 National Defense Authorization Act (NDAA), as amended by Section 813(b) of the 2010 NDAA and Section 832 of the 2011 NDAA. DoD has determined that the updates implementing Section 832 of the 2011 NDAA do not require additional public comment. These updates are in direct compliance with current statute, do not set a precedent in updating the interim final, and any delay in implementing these updates would be detrimental to U.S. security. Background This Final Rule [1] is required to meet the mandate of Section 862 of the FY 2008 NDAA, as amended, which lays out two requirements:

From the NIST SP 800-172 Rev 3 Final Public Draft: Advanced automation and predictive NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 analytics capabilities are typically supported by artificial intelligence concepts and 1516

Evaluation material used to determine potential for promotion in the Military Services, but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (b) Promises of confidentiality. (1) Only the identity of sources that have been given an express promise of confidentiality may be protected from disclosure under paragraphs (a)(1), (5), and (7) of this section. However, the identity of sources who were given implied promises of confidentiality in inquiries conducted before September 27, 1975, also may be protected from disclosure. (2) Ensure promises of confidentiality are not automatically given but are used sparingly. Establish appropriate procedures and identify fully categories of individuals who may make such promises. Promises of confidentiality shall be made only when they are essential to obtain the information sought (see 5 CFR part 736). (c) Access to records for which specific exemptions are claimed. Deny the individual access only to those portions of the records for which the claimed exemption applies. Subpart G-Publication Requirements §-310.30 Federal Register publication. (a) What must be published in the Federal Register . (1) Four types of documents relating to the Privacy Program must be published in the Federal Register : (i) DoD Component Privacy Procedural rules; (ii) DoD Component exemption rules; and (iii) System notices. (iv) Match notices (See subpart L to this part). (2) See DoD 5025.1-M, [9] Directive Systems Procedures and Administrative Instruction (AI) No. 102, [10] Office of the Secretary of Defense Federal Register System for information pertaining to the preparation of documents for publication in the Federal Register . (b) The effect of publication in the Federal Register . Publication of a document in the Federal Register constitutes official public notice of the existence and content of the document. (c) DoD Component rules. (1) Component Privacy Program procedures and Component exemption rules are subject to the rulemaking procedures prescribed in AI 102. (2) System notices are not subject to formal rulemaking and are published in the Federal Register as Notices, not rules. (3) Privacy procedural and exemption rules are incorporated automatically into the CFR. System notices are not published in the CFR. (d) Submission of rules for publication. (1) Submit to the DPO, ODA&M, all proposed rules implementing this part in proper format (see DoD 5025.1-M and AI 102) for publication in the Federal Register . (2) This part has been published as a final rule in the Federal Register . Therefore, incorporate it into your Component rules rather than by republication (see AI 102). (3) DoD Component procedural rules that simply implement this Regulation need only be published as final rules in the Federal Register (see DoD 5025.1-M and AI 102). If the Component procedural rule supplements this part in any manner, they must be published as a proposed rule before being published as a final rule.

NIST reserves the right to add or remove platforms in future updates to the SCAP 1.2 Validation Program. The platforms supported at the release of this document included several versions of Microsoft Windows and Red Hat Enterprise Linux. The SCAP Validation Program may add support for new platforms which will be listed on the SCAP Validation Program web page. For the most current list of available platforms, please refer to <http://scap.nist.gov/validation>. This document identifies a specific set of SCAP component specifications as described in Section 2 and the associated Derived

Test Requirements (DTRs) as described in Section 4. Minor updates to SCAP component specifications and products do not invalidate currently validated products. Major changes in functionality, including support for new SCAP technologies, may require product revalidation.

At the same time, the procedures in this rule allow companies determined to be under FOCI to be cleared through a FOCI mitigation or negation agreement and thus realize billions of dollars in classified contracts. By maintaining the capability for foreign-owned U.S. contractors to compete for classified contracts with FOCI mitigation, DoD, through the NISP, enhances competition and realizes cost savings through that competition. Background DoD, as one of the four NISP CSAs, provides oversight of more than 10,000 U.S. contractors as well as another 3,000 divisions and branch offices of those contractors on behalf of the DoD Components and the non-DoD Components. Non-DoD Components issuing contracts requiring access to classified information who are not one of the four designated NISP CSAs (i.e., the Department of Energy, the Office of the Director of National Intelligence, the Nuclear Regulatory Commission and the DoD) must enter into agreements with DoD to establish the terms of oversight on their behalf. Currently, the procedures for assessing initial FCL eligibility for U.S. companies and continued FCL eligibility for U.S. contractors which may be subject to FOCI are not uniform or consistent since these procedures do not apply to the non-DoD Components. Currently, DoD does not have uniform procedures to assess the risks and the potential adverse impact on the performance of contracts requiring access to classified information due to any FOCI information reported by U.S. contractors or U.S. companies in process for an FCL. The rule will provide uniform and effective procedures for DoD to assess the risks associated with reports of material changes to FOCI information which are submitted annually by U.S. contractors. The rule also establishes procedures and criteria for appropriate actions to mitigate or negate any existing FOCI factors when DoD determines a U.S. company in process for an FCL or a U.S. contractor is under FOCI and is thus ineligible for access to classified information. The rule also prescribes responsibilities for FOCI matters, to include assessment of risks which may result from a contractor's FOCI information. Finally, it outlines security measures DoD may consider, implement, and oversee to mitigate or negate the effects of FOCI to an acceptable level for classified contract performance. The addition of this rule is part of DoD's retrospective plan, completed in August 2011, under Executive Order 13563 , Improving Regulation and (printed page 19469) Regulatory Review. Executive Order 13563

The Contractor may implement alternative, additional, or compensating cyber supply chain risk management security controls from those stated in the contract, when authorized in writing by the Contracting Officer. (h) Notifiable incident reporting, incident response and threat reporting. For contract coverage on security incident and cyber threat reporting, see FAR clause 52.239-ZZ, Incident and Threat Reporting and Incident Response Requirements for Products or Services Containing Information and Communications Technology, in this contract. (i) Limitations on access to, use, and disclosure of Government data, Government-related data, and any associated metadata. (1) The Contractor shall not access, use, or disclose Government data, Government-related data, and any associated metadata unless specifically authorized under the contract or task or delivery order or in writing by the Contracting Officer. (i) When authorized, the access, use, or disclosure of Government data, Government-related data, and any associated metadata shall only be for purposes specified in the contract or task or delivery order. (ii) The Contractor shall ensure that its employees are subject to all such access, use, and disclosure prohibitions and obligations of this paragraph. (iii) The access, use, and disclosure prohibitions and obligations of this paragraph shall survive the expiration or termination of this contract. (2) The Contractor shall use Government metadata only to manage the operational environment that supports the Government data and for no other purpose unless otherwise permitted with the prior written approval of the Contracting Officer. (3) The Contractor shall notify the Contracting Officer promptly of any requests from a third-party for access to Government data, Government-related data, or any associated metadata, including any warrants, seizures, or subpoenas it receives, including those from another Federal, State, or local agency. The Contractor shall comply with applicable clauses, regulations, and laws concerning protection of Government data and Government-related data from any unauthorized disclosure. (4) The Contractor shall not publish or disclose in any manner, without the Contracting Officer's written consent, the details of any safeguards either designed or developed by the Contractor under this contract or otherwise provided by the Government. (j) Cryptographic key services. The Government reserves the right to implement and operate its own cryptographic key management, key revocation, and key escrow services. If key services are provided by the contractor, the contractor shall provide the agency with applicable key material and services. (k) List of

operational technology equipment. Unless the contract states otherwise, the Contractor shall develop and maintain a list of the physical location of all operational technology included within the boundary of a FIS covered by this contract.

For CMMC Level 3, the estimates factor in the assessment, reporting and affirmation activities in addition to estimates for NRE and RE to implement and maintain CMMC Level 3 requirements. CMMC Level 3 requirements are a subset of NIST SP 800-172 Feb2021 Enhanced Security Requirements as described in § 170.30 of the CMMC rule and are not currently required through other regulations. CMMC Level 3 is expected to apply only to a small subset of DIB contractors. The Cost Categories used for each CMMC Level are described below:

1. Nonrecurring Engineering Costs: Estimates consist of hardware, software, and the associated labor to implement the same. Costs associated with implementing the requirements defined in FAR clause 52.204-21 and NIST SP 800-171 R2 are assumed to have been implemented and are therefore not accounted for in this cost estimate. As such, these costs only appear in CMMC Level 3. Where nonrecurring engineering costs are referenced, they are only accounted for as a one-time occurrence and are reflected in the year of the initial assessment.
2. Recurring Engineering Costs: Estimates consist of annually recurring fees and associated labor for technology refresh. Costs associated with implementing the requirements defined in FAR clause 52.204-21 and NIST SP 800-171 R2 are assumed to have been implemented and are therefore not accounted for in this cost estimate. As such, these costs only appear in CMMC Level 3.
- Assessment Costs: Estimates consist of activities for pre-assessment preparations (which includes gathering and/or developing evidence that the assessment objectives for each requirement have been satisfied), conducting and/or participating in the actual assessment, and completion of any post-assessment work. Assessment costs are represented by notional phases. Assessment costs assume the offeror/contractor passes the assessment on the first attempt (conditional with an allowable POA&M or final). Each phase includes an estimate of hours to conduct the assessment activities including:
 - (a) Labor hour estimates for a company (and any ESP support) to prepare for and participate in the assessment.
 - (b) C3PAO cost estimates for companies pursuing a certification.
 - (c) Labor hour estimates for certified assessors to work with the small business to conduct the actual assessment. (printed page 83205)Assessment Costs broken down into phases.
 - Phase 1: Planning and preparing for the assessment.
 - Phase 2: Conducting the assessment (self or C3PAO).
 - Phase 3: Reporting of Assessment Results.
 - Phase 4: POA&M Closeout (for CMMC Level 3 only, where allowed, if applicable). CMMC allows a limited open Plan of Action and Milestones (POA&M) for a period of 180 days to remediate the POA&M, see § 170.37.
3. Affirmations:

CM.L2-3.4.5 · Access Restrictions for Change CMMC Assessment Guide · Level 2 | Version 2.13 102
into the datacenter, upgrades the hardware, expands the storage in the operating system (OS), and departs. The manager verifies the upgrade and disables the privileged account [h]. Potential Assessment Considerations · Are only employees who are approved to make physical or logical changes on systems allowed to do so [a,d,e,h]? · Are authorized personnel approved and documented by the service owner and IT security [a,e]? · Does all change documentation include the name of the authorized employee making the change [b,d,f,h]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.4.5

Thus, the Department proposes to require a regulated entity to consider the ability of its implementation of a particular security measure to aid it in preventing, withstanding, and recovering from an emergency or other occurrence that affects the confidentiality, integrity, or availability of ePHI, including a successful security incident. The Department proposes this new requirement to better enable regulated entities to ensure the confidentiality, integrity, and availability of all ePHI that they create, receive, maintain, or transmit. The general rules require regulated entities to not only prevent threats and hazards to the confidentiality and integrity of ePHI, but also to ensure the availability of ePHI, even during a security incident that has the potential to severely hinder the ability of a regulated entity to provide health care or to bring it to a standstill. This new factor would require a regulated entity to consider whether a particular approach to complying with a standard and the associated implementation specifications can help it recover from an emergency or other occurrence, in addition to maintaining operations throughout the event. The Department proposes this factor to complement its proposals to strengthen the standards for security incident procedures [428] and contingency planning [429] and proposals for new standards for patch management [430] and vulnerability management, [431] discussed in detail below. If finalized, these proposals would help to ensure that regulated entities put in place the necessary measures to implement these standards. The factors contemplate that regulated entities will regularly evaluate the security measures they have applied to comply with the

standards and implementation specifications based on the technology available and known risks and vulnerabilities at the time of the evaluation. The Department expects that when the existing factors are considered with the factor proposed in this NPRM, a regulated entity would be required to consider whether a specific technical control has become sufficiently ubiquitous such that choosing not to adopt it would be unreasonable. c. Section 164.306(c)-Standards and Implementation Specifications To address the Department's concerns regarding the apparent misunderstanding by regulated entities of -addressable-, we propose to modify 45 CFR 164.306(c) and (d)

3.6.1 Multiple Capabilities Support Addressing Each Attack Step | ... 3.6.1 Multiple Capabilities Support Addressing Each Attack Step There is a many-to-many relationship between security capabilities and attack steps.

This system of records is exempt from subsections (c)(3) and (d) of section 552a of 5 U.S.C. which would require the disclosure of investigatory material compiled solely for the purpose of determining access to classified information, but only to the extent that the disclosure of such material would reveal the identity of a source who furnished information to the Government under an expressed promise that the identity of the source would be held in confidence, or prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. A determination will be made at the time of the request for a record concerning whether specific information would reveal the identity of a source. This exemption is required in order to protect the confidentiality of the sources of information compiled for the purpose of determining access to classified information. This confidentiality helps maintain the Government's continued access to information from persons who would otherwise refuse to give it. (4) System identifier and name. DWHS P32, Standards of Conduct Inquiry File. (i) Exemption. This system of records is exempted from subsections (c)(3) and (d) of 5 U.S.C. 552a, which would require the disclosure of: Investigatory material compiled for law enforcement purposes; or investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, or Federal contracts, but only to the extent that the disclosure of such material would reveal the identity of a source who furnished information to the Government under an express promise or, prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. If any individual is denied any right, privilege, or benefit that he would otherwise be entitled by Federal law, or otherwise be eligible, as a result of the maintenance of investigatory material compiled for law enforcement purposes, the material shall be provided to that individual, except to the extent that its disclosure would reveal the identity of a source who furnished information to the Government under an express promise or, prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. At the time of the request for a record, a determination will be made concerning whether a right, privilege, or benefit is denied or specific information would reveal the identity of a source. (ii) Authority. 5 U.S.C. 552a(k)(2) and (5). (iii) Reasons.

Identification of a known vulnerability in a relevant electronic information system or a component thereof is a necessary precursor for a regulated entity to take action to mitigate the vulnerability. A 2019 study on vulnerability and patch management found that 48 percent of respondents reported that their organizations had at least one breach in the preceding two years. Of those, 60 percent said that the breaches could have occurred because an available patch for a known vulnerability had not been applied. [804] Accordingly, the Department also proposes a new implementation specification for monitoring at proposed 45 CFR 164.312(h)(2)(ii) to require that a regulated entity monitor authoritative sources for known vulnerabilities on an ongoing basis and take action to remediate identified vulnerabilities in accordance with the regulated entity's patch management program. [805] The Department expects such monitoring to be conducted on an ongoing basis and is not proposing to specify a minimum time interval for reviewing sources. We are also not proposing to prescribe the specific sources of known vulnerabilities because such sources may change over time and the vulnerabilities for which regulated entities may be monitoring may vary greatly among regulated entities. We propose to require that the sources used must be authoritative. Examples of authoritative sources of known vulnerabilities would include NIST's National Vulnerability Database [806] and CISA's Known Exploited Vulnerabilities Catalog. [807] The proposed implementation specification for penetration testing at 45 CFR 164.312(h)(2)(iii) would require a regulated entity to conduct periodic testing of the regulated entity's relevant electronic information systems for vulnerabilities, commonly referred to as penetration testing. Penetration tests identify vulnerabilities in the security features of an application, system, or

network by mimicking real-world attacks [808] and are an effective way to identify weaknesses that could be exploited by an attacker. [809] The proposal would require such testing to be conducted by qualified person(s). We propose to describe a qualified person as a person with appropriate knowledge of and experience with generally accepted cybersecurity principles and methods for ensuring the confidentiality, integrity, and availability of ePHI. We believe that within the cybersecurity industry, it is understood that a person who is qualified to conduct such penetration testing is an individual who has a combination of one or more qualifying credentials, skills, or experiences to perform ·ethical hacking· or ·offensive security· of information systems. The proposal would require a regulated entity to conduct such testing at least once every 12 months, or in accordance with the regulated entity's risk analysis, [810] whichever is more frequent. Lastly, we are proposing a new implementation specification for patch and update installation at 45 CFR 164.312(h)(2)(iv)

24/7, with allowance for remote/on-call staff. (xi) IR.L3-3.6.2e Establish and maintain a cyber-incident response team that can be deployed by the organization within 24 hours. (xii) PS.L3-3.9.2e Ensure that organizational systems are protected if adverse information develops or is obtained about individuals with access to CUI. (xiii) RA.L3-3.11.1e Employ threat intelligence, at a minimum from open or commercial sources, and any DoD-provided sources, as part of a risk assessment to guide and inform the development of organizational systems, security architectures, selection of security solutions, monitoring, threat hunting, and response and recovery activities. (xiv) RA.L3-3.11.2e Conduct cyber threat hunting activities on an on-going aperiodic basis or when indications warrant, to search for indicators of compromise in organizational systems and detect, track, and disrupt threats that evade existing controls. (xv) RA.L3-3.11.3e Employ advanced automation and analytics capabilities in support of analysts to predict and identify risks to organizations, systems, and system components. (xvi) RA.L3-3.11.4e Document or reference in the system security plan the security solution selected, the rationale for the security solution, and the risk determination. (xvii) RA.L3-3.11.5e Assess the effectiveness of security solutions at least annually or upon receipt of relevant cyber threat information, or in response to a relevant cyber incident, to address anticipated risk to organizational systems and the organization based on current and accumulated threat intelligence. (xviii) RA.L3-3.11.6e Assess, respond to, and monitor supply chain risks associated with organizational systems and system components. (xix) RA.L3-3.11.7e Develop a plan for managing supply chain risks associated with organizational systems and system components; update the plan at least annually, and upon receipt of relevant cyber threat information, or in response to a relevant cyber incident. (xx) CA.L3-3.12.1e Conduct penetration testing at least annually or when significant security changes are made to the system, leveraging automated scanning tools and ad hoc tests using subject matter experts. (xxi) SC.L3-3.13.4e Employ physical isolation techniques or logical isolation techniques or both in organizational systems and system components. (xxii) SI.L3-3.14.1e Verify the integrity of security critical and essential software using root of trust mechanisms or cryptographic signatures. (xxiii) SI.L3-3.14.3e Ensure that specialized assets including IoT, IIoT, OT, GFE, Restricted Information Systems, and test equipment are included in the scope of the specified enhanced security requirements or are segregated in purpose-specific networks. (xxiv) SI.L3-3.14.6e Use threat indicator information and effective mitigations obtained from, at a minimum, open or commercial sources, and any DoD-provided sources, to guide and inform intrusion detection and threat hunting.

From the NIST SP 800-172 Rev 3 Final Public Draft: Such statements should be addressed to: 800-171comments@list.nist.gov NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 vi Table of Contents 114

Similar to the requirements for non-cloud FISs in clause 52.239-YY, the clause 52.239-XX: (1) at paragraph (c), reserves the Government's right to implement and operate its own cryptographic key services under the contract; (2) at paragraph (d), specifies the limitations on contractor access to, use, and disclosure of Government data and Government-related data under the contract; (3) at paragraph (e), requires contractors to handle security incident and cyber threat reporting in accordance with proposed FAR clause 52.239-ZZ; (4) at paragraph (f), specifies the terms for the Government's authorized representatives' access to Government and Government-related data, contractor personnel, and contractor facilities; (5) at paragraph (g), requires contractors to notify the contracting officer of any requests from a third-party (including another Federal, State, or local agency) for access to Government data and Government-related data; (6) at paragraph (h), requires contractors to indemnify the Government from any liability that arises out of the

performance of the contract because of the contractor's introduction of certain information or matter into Government data or the contractor's unauthorized disclosure of certain information or material; and (7) at paragraph (i), specifies when to include the substance of the clause in subcontracts. III. Applicability to Contracts at or Below the Simplified Acquisition Threshold (SAT) and for Commercial Products (Including Commercially Available Off-the-Shelf (COTS) Items) or for Commercial Services This rule applies section 7 of the Internet of Things Cybersecurity Improvement Act of 2020 (15 U.S.C. 278g-3e) to acquisitions valued at or below the SAT because of the notwithstanding section 1905 in 15 U.S.C. 278g-3e(a)(2) which applies the Act to such acquisitions. This rule also applies to acquisitions for commercial products, including COTS items, and commercial services because Government data and systems require protection regardless of dollar value or commerciality of the product or service. To implement paragraphs (a) and (b)(1) of section 7 of the Act, this rule adds a new policy at FAR 39.X02-1(b), Prohibited IoT devices in Federal information systems. The policy prescribed at FAR 39.X02-1(b) applies when agencies are acquiring IoT devices. A. Applicability to Contracts at or Below the Simplified Acquisition Threshold 41 U.S.C. 1905

From the NIST SP 800-172 Rev 3 Final Public Draft: <https://doi.org/10.6028/NIST.SP.800-53B.2675>
 [14] Ross RS, Pillitteri VY, Graubart R, Bodeau D, McQuaid R (2021) Developing Cyber-Resilient Systems: A Systems Security Engineering Approach. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-160v2r1.
<https://doi.org/10.6028/NIST.SP.800-160v2r1> [15] Johnson CS, Waltermire DA, Badger ML, Skorupka C, Snyder J (2016) Guide to Cyber Threat Information Sharing. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-150.
<https://doi.org/10.6028/NIST.SP.800-150> [16] Joint Task Force Transformation Initiative (2022) Assessing Security and Privacy Controls in Information Systems and Organizations. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-150v2r1.

Requirements for safeguarding CUI residing on Federal and non-Federal systems, as identified in the SF XXX, Controlled Unclassified Information (CUI) Requirements; Requirements for reporting and managing security incidents; Actions that may be necessary to validate compliance; Minimum CUI training requirements; and The requirement for contractors to flow down CUI requirements to subcontractors, if applicable. (15) FAR 52.204-21, Basic Safeguarding of Covered Contractor Information Systems. Text is added for the definition and at paragraph (b)(3) for the identification of covered Federal information. (16) FAR clause 52.212-5 is updated to reflect that FAR clause 52.204-XX is applicable to acquisitions of commercial products and services. FAR clause 52.213-4 is updated to reflect usage of the FAR 52.204-XX clause in simplified acquisitions for other than commercial products or services. FAR clause 52.244-6 is updated to address the flow down to subcontracts for the two new clauses. (17) Additional minor edits are made at FAR 1.106 to add the OMB control number information for the provision and clause, at FAR 42.302 to update a cross-reference, and at FAR subpart 53.2 to add the new SF XXX, Controlled Unclassified Information (CUI) Requirements. III. Applicability to Contracts at or Below the Simplified Acquisition Threshold (SAT) and for Commercial Products, Including Commercially Available Off-the-Shelf (COTS) Items, or Commercial Services This rule proposes a new provision at FAR 52.204-WW, Notice of Controlled Unclassified Information Requirements. The proposed provision is prescribed at FAR 4.403-7(a) for use in solicitations that contain the clause at FAR 52.204-XX or the clause at FAR 52.204-YY. The rule proposes a new clause at FAR 52.204-XX, Controlled Unclassified Information. The proposed clause is (printed page 4281) prescribed at FAR 4.403-7(b) for use in solicitations and contracts if the requiring activity has marked the Yes box in Part A of the SF XXX, except for solicitations and contracts solely for the acquisition of COTS items. The rule proposes a new clause at FAR 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information. The proposed clause is prescribed at FAR 4.403-7(c) for use in solicitations and contracts if the requiring activity has marked the No box in Part A of the SF XXX, excluding solicitations and contracts solely for the acquisition of COTS items. This rule also proposes to amend the FAR to implement 32 CFR part 2002

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.13.05E Change Processing and Storage Locations 1839 C Change the location of [Assignment: organization-defined processing and/or storage] [Selection (one): [Assignment: organization-defined time frequency]; at random time intervals]. DISCUSSION Adversaries target critical missions and business functions and the systems that support those missions and business functions while also trying to minimize the exposure of

their existence and tradecraft. The static, homogeneous, and deterministic nature of organizational systems targeted by adversaries make such systems more susceptible to attacks with less adversary cost and effort to be successful. Changing processing and storage locations (also referred to as moving target defense) addresses the advanced persistent threat using tech

From the NIST SP 800-172 Rev 3 Final Public Draft: insider threat 2982 The threat that an insider will use their authorized access, wittingly or unwittingly, to do harm to the security of the United States. This threat can include damage to the United States through espionage, terrorism, unauthorized disclosure, or through the loss or degradation of departmental resources or capabilities. integrity Guarding against improper information modification or destruction and includes ensuring information non-repudiation and authenticity. [20] Internet of Things The network of devices that contain the hardware, software, firmware, and actuators which allow the devices to connect, interact, and freely exchange data and information. malicious code Software or firmware intended to perform an unauthorized process that will have an adverse

(K) Use the clause at 252.246-7003, Notification of Potential Safety Issues, as prescribed in 246.371. (L) Use the provision at 252.247-7026, Evaluation Preference for Use of Domestic Shipyards-Applicable to Acquisition of Carriage by Vessel for DoD Cargo in the Coastwise or Noncontiguous Trade, as prescribed in 247.574(e).] (M) Use the clause at 252.247-7027, Riding Gang Member Requirements, as prescribed in 247.574(f). * * * * * PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 5. Add section 252.204-7011 to read as follows: 252.204-7011 Alternative Line Item Structure. As prescribed in 204.7109(b), insert the following provision: ALTERNATIVE LINE-ITEM STRUCTURE (SEP 2011) (a) Line items are the basic structural elements in a solicitation or contract that provide for the organization of contract requirements to facilitate pricing, delivery, inspection, acceptance and payment. Line items are organized into contract line items, subline items, and exhibit line items. Separate line items should be established to account for separate pricing, identification (see section 211.274 of the Defense Federal Acquisition Regulation Supplement), deliveries, or funding. The Government recognizes that the line item structure in this solicitation may not conform to every offeror's practices. Failure to correct these issues can result in difficulties in accounting for deliveries and processing payments. Therefore, offerors are invited to propose an alternative line item structure for items on which bids, proposals, or quotes are requested in this solicitation to ensure that the resulting contract structure is economically and administratively advantageous to the Government and the Contractor. (b) If an alternative line item structure is proposed, the structure must be consistent with subpart 204.71 of the Defense Federal Acquisition Regulation Supplement and PGI 204.71. A sample solicitation line-item structure and a corresponding offer of a proposed alternative line-item structure follow. Solicitation: Item No. Supplies/Service Quantity Unit Unit price Amount 0001 Computer, Desktop with CPU, Monitor, Keyboard and Mouse 20 EA Alternative line-item structure offer where monitors are shipped separately: (printed page 58140) Item No. Supplies/Service Quantity Unit Unit Price Amount 0001 Computer, Desktop with CPU, Keyboard and Mouse 20 EA 0002 Monitor 20 EA (End of provision) [FR Doc. 2011-23953 Filed 9-19-11; 8:45 am] BILLING CODE 5001-08-P

CIS Safeguard 4.8 · Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function. Implementation Groups: 2,3 Asset Type: devices Security Function: protect Parent Control: Secure Configuration of Enterprise Assets and Software

) provides a single integrated, cohesive industrial security program to protect classified information to preserve our Nation's economic and technological interests. Under the NISP, the USG establishes requirements for the protection of classified information to be safeguarded in a manner equivalent to its protection within the executive branch of USG, where practicable. For industry, those requirements are included in the NISPOM. When bound by contract, license, or grant, industry must comply with the NISPOM and any Cognizant Security Agency (CSA)-specific supplementary guidance for unique CSA mission requirements. As the Executive Agent of the NISP, the Secretary of Defense is responsible for overall implementation of the program. The Department of Defense (DoD) issues and maintains the NISPOM with the concurrence of the other four NISP CSAs and in consultation with other affected Federal agencies. DoD codified the NISPOM in a final rule on December 21, 2020 (85 FR 83300-83364) National Industrial Security Program Operating Manual (NISPOM) to add 32 CFR part 117 to the Code of Federal Regulations (CFR). The rule was effective on February 24, 2021. In

addition to adding the NISPOM to the CFR, the final rule incorporated requirements of Security Executive Agent Directive (SEAD) 3, Reporting Requirements for Personnel with Access to Classified Information or Who Hold a Sensitive Position. SEAD 3 requires reporting by all contractor cleared personnel who have been granted eligibility for access to classified information. The final rule provided a single nation-wide implementation plan to include SEAD 3 reporting by all contractor cleared personnel to report specific activities that may adversely impact their continued national security eligibility, such as reporting of foreign travel and foreign contacts. NISP CSAs are required to conduct an analysis of such reported activities to determine whether they pose a potential threat to national security and take appropriate action. Finally, the rule also implemented the provisions of Section 842 of Public Law 155-232, which removed the requirement for a covered National Technology and Industrial Base (NTIB) entity operating under a special security agreement pursuant to the NISP to obtain a national interest determination as a condition for access to proscribed information. The 60-day public comment period ended on February 19, 2021. On August 19, 2021, DoD published a technical amendment to the December final rule (at 86 FR 46597-46599

(B) If a prospective subcontractor requires access to classified information during the pre-award phase and does not have the appropriate entity eligibility determination or a classified information safeguarding capability, the prime contractor will request the CSA of the subcontractor to initiate the necessary action. (iii) If access to classified information will not be required, the contract is not a classified contract within the meaning of this rule. If the prime contract contains requirements for release or disclosure of protected information that is not classified, such as CUI, the requirements will be incorporated in the solicitation and the subcontract and are not covered by this rule. (2) Prospective subcontractors entity eligibility determinations. (i) The prime contractor will verify whether the prospective subcontractors have the appropriate entity eligibility determination and also a classified information safeguarding capability, if a subcontract requirement. This determination can be made if there is an existing contractual relationship between the parties involving classified information of the same or higher category, and must be verified by accessing the CSA-designated database, or by contacting the CSA. (ii) If a prospective subcontractor does not have the appropriate entity eligibility determination or a classified information safeguarding capability, the prime contractor will request that the CSA of the subcontractor initiate the necessary action. (A) Requests will include, at a minimum, the full name, address, and contact information for the requester; the full name, address, and contact information for a contact at the facility to be processed for an entity eligibility determination; the level of clearance and the required classified information safeguarding capability; and full justification for the request. (B) Requests for safeguarding capability will include a description, quantity, end-item, and classification of the information related to the proposed subcontract. (C) Other factors necessary to help the CSA determine if the prospective subcontractor meets the requirements of this rule will be identified, such as any special access requirements. (3) Lead time for entity eligibility determination when awarding to an uncleared subcontractor. Requesting contractors will allow sufficient lead time in connection with the award of a classified subcontract to enable an uncleared bidder to be processed for the necessary entity eligibility determination. When the entity eligibility determination cannot be granted in sufficient time to qualify the prospective subcontractor for participation in the current procurement action, the CSA will continue the entity eligibility determination processing action to qualify the prospective subcontractor for future contract consideration provided: (i) The delay in processing the entity eligibility determination was not caused by a lack of cooperation on the part of the prospective subcontractor.

The NC green onion traceback investigation in 2003, which was part of the largest Hepatitis A outbreak that has ever occurred in the United States, is another example of the importance of intrastate records. There, the amount of time spent on the traceback within that State was twice as long as the other three tracebacks done in other states because the distributor in NC did not have records. Traceback from the TN outbreak took over a month, the GA traceback took a month, and Pennsylvania (PA) traceback took a week. Because we had no intrastate records in the NC outbreak, the traceback was determined to be inconclusive after two months, which meant that we would not have been able to identify the farms involved if it had not been for the other outbreaks. This year, there was an *Escherichia coli* (*E. coli*) O157:H7 outbreak associated with bagged lettuce product in CA that was only in intrastate commerce. That traceback might have been lost had records not have been available. Exempting intrastate transporters could significantly impede FDA's ability rapidly and effectively to respond to a public health emergency involving a food transported within

a state, particularly if the adulteration occurred during transport and the food was delivered to multiple sources within the State. In scenarios where time is of the essence to prevent serious injuries or death on a large scale, having records available becomes even more critical. In addition, not only must FDA be able to rapidly obtain records, it is imperative that FDA be assured that those records contain certain essential information to allow FDA to prevent further harm in an efficient and effective manner. Additional examples of circumstances involving food products that have significant intrastate manufacturing/processing or distribution are provided in the following paragraphs: An intrastate sandwich/snack food company that sells to retail outlets for consumption had an outbreak of Listeriosis or Salmonellosis that was traced back to the sandwiches. The product was completely distributed using the company trucks within the state. FDA was unable to determine which sandwiches caused the outbreak. The sandwiches were delivered to retail customers, and it was impossible to track which sandwiches went to which retailer. The transporter did not track which product was delivered to which location. In this case, the firm had to recall all of its products. Retail stores regularly purchase food, especially locally grown produce, from truck farmers. These farm trucks travel from store to store within a state, sometimes selling an entire truckload to a store, other times a portion. There is no manifest or record other than a bill of sale-e.g., 200 cantaloupes from Farmer Brown. If the contamination occurred on the truck, FDA would not have a record from the truck of all other delivery sites.

These U.S. Munitions List commodities are authorized by the U.S. Government under the U.S. [AUS or UK, as applicable] Defense Trade Cooperation Treaty for export only to [AUS or UK, as applicable] for use in approved projects, programs or operations by members of the [AUS or UK, as applicable] Community. They may not be retransferred or re-exported or used outside of an approved project, program, or operation, either in their original form or after being incorporated into other end-items, without the prior written approval of the U.S. Department of State. (5) Labeling. (i) Defense articles (other than technical data) will be individually labeled with the appropriate identification; or, where such labeling is impracticable (e.g., propellants, chemicals), will be accompanied by documentation (such as contracts or invoices) clearly associating the defense articles with the appropriate markings. (ii) Technical data (including data packages, technical papers, manuals, presentations, specifications, guides and reports), regardless of media or means of transmission (i.e., physical, oral, or electronic), will be individually labeled with the appropriate identification detailed. Where such labeling is impracticable, the data will be accompanied by documentation (such as contracts or invoices) or oral notification clearly associating the technical data with the appropriate markings. (iii) Defense services will be accompanied by documentation (e.g. contracts, invoices, shipping bills, or bills of lading clearly labeled with the appropriate identification). (6) Transfers. (i) All defense articles that fall under the scope of the Treaties must be transferred from the U.S. point of embarkation through channels approved by both the United States and the UK or the United States and AUS, as applicable. (ii) For transfers of defense articles as freight, the contractor will prepare a transportation plan. For transfer of classified U.S. defense articles, a freight forwarder must have a valid entity eligibility determination and a classified information storage capability at the appropriate level. For unclassified U.S. defense articles transferred as freight, a freight forwarder is not required to be cleared. (7) Records. Contractors will maintain records of exports, transfers, re-exports, or re-transfers of defense articles subject to the Treaties for a minimum of five years. The contractor will make records available to the CSA upon request. In accordance with the ITAR parts 126.16 and 126.17 the records will contain: (i) Port of entry or exit. (ii) Date and time of export or import. (iii) Method of export or import. (iv) Commodity code and description of the commodity, including technical data. (v) Value of export. (vi) Justification for export under the Treaties. (vii) End-user or end-use. (viii) Identification of all U.S. and foreign parties to the transaction. (ix) How export was marked. (x) Security classification of the export.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary [DoD-2006-OS-0129] RIN 0790-AB03 32 CFR Part 310 AGENCY: Department of Defense. ACTION: Final rule. SUMMARY: The Department of Defense is updating policies and responsibilities for the Defense Privacy Program which implements

the Privacy Act of 1974. EFFECTIVE DATE: April 13, 2007. FOR FURTHER INFORMATION CONTACT: Mr. Vahan Moushegian, Jr., at (703) 607-2943. SUPPLEMENTARY INFORMATION: The proposed rule was published in the Federal Register on July 14, 2006 at 71 FR 40282. No public comments were received. Some administrative changes were made as a result of comments on the corresponding DoD issuance and Office of Management and Budget guidance. Changes involve revision of the terms for personal and compromised information; the incorporation of additional considerations when determining if a social security number will be collected; a reorganization of the procedures involving Congressional or General Accountability Office access to records; an expanded explanation of record disposal procedures and the access exemption; additional consideration involving training and technical/special security requirements; and new notification procedures when there is a loss or theft of information. Executive Order (E.O.) 12866, 'Regulatory Planning and Review' It has been determined that 32 CFR part 310 is not a significant regulatory action. The rule does not (1) Have an annual effect on the economy of \$100 million or more or adversely affect in a material way the economy; a sector of the economy; productivity; competition; jobs; the environment; public health or safety; or State, local, or tribal governments or communities; (2) Create a serious inconsistency or otherwise interfere with an action taken or planned by another Agency; (3) Materially alter the budgetary impact of entitlements, grants, user fees, or loan programs, or the rights and obligations of recipients thereof; or (4) Raise novel legal or policy issues arising out of legal mandates, the President's priorities, or the principles set forth in this Executive Order. Public Law 96-354, 'Regulatory Flexibility Act' (5 U.S.C. Chapter 6) It has been determined that this rule is not subject to the Regulatory Flexibility Act because it would not, if promulgated, have a significant economic impact on a substantial number of small entities because it is only concerned with the administration of Privacy Program within the Department of Defense. Public Law 96-511, 'Paperwork Reduction Act' (

Exemptions. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (B) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(4)(G) and (H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5). (iii) Reasons. Exempted portions of this system contain information considered relevant and necessary to make a release determination as to qualifications, eligibility, or suitability for Federal employment, and was obtained by providing an express or implied promise to the source that his or her identity would not be revealed to the subject of the record. (11) System identifier and name. N05354-1, Equal Opportunity Information Management System. (i) Exemptions. (A) Information specifically authorized to be classified under E.O. 12958, as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (C) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(4)(G) through (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(1) and (k)(5). (iii) Reasons. Granting access to information in this system of records could result in the disclosure of classified material, or reveal the identity of a source who furnished information to the Government under an express or implied promise of confidentiality. Material will be screened to permit access to unclassified material and to information that will not disclose the identity of a confidential source. (12) System identifier and name. N05520-1, Personnel Security Eligibility Information System. (i) Exemptions. (A) Information specifically authorized to be classified under E.O. 12958, as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (B) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source.

From the NIST SP 800-172 Rev 3 Final Public Draft: · Implementing dual authorization controls for critical or sensitive operations 337 · Limiting persistent storage to isolated enclaves or domains · Implementing a comply-to-connect approach for systems and networks · Extending configuration

management requirements by establishing authoritative sources for addressing changes to systems and system components · Periodically refreshing or upgrading organizational systems and system components to a known state or developing new systems or components · Employing a security operations center with advanced analytics to support continuous monitoring and the protection of systems · Using deception to confuse and mislead adversaries regarding the information they use for decision-making, the value and authenticity of the information they a

The DoD disagreed with the comment that the CAICO should determine the length of time a CCP certification is valid. DoD has a significant interest in ensuring the quality of assessors in the CMMC ecosystem and the currency of their training. The DoD does not agree with the assertion that managerial, and personnel related skills are most relevant for success as a Lead Assessor. As written, § 170.11 of the rule requires Lead Assessors to have a balance of technical and managerial expertise. A Lead Assessor also requires assessment or audit experience. The DoD views these skills as the minimum required to adequately provide the technical guidance and managerial oversight of the assessment team. The DoD declined to revise the rule to specify IT and/or Cybersecurity for the required audit experience. The DoD also disagreed with a recommendation to require Lead CCAs to have industry-specific knowledge of the industry in which the OSC being assessed participates. The DoD found that this requirement would unreasonably restrict C3PAOs from participating in a broad range of assessments and could have a negative effect on the ability of the DIB to schedule CMMC Level 2 certification assessments. The OSC can select a C3PAO with the experience it considers valuable. The DoD declined a commentor's request to modify the rule to allow the CAICO to determine the requirement for the frequency of CCA/CCP certification. The DoD considers the 3 years certification period a key CMMC program requirement that will be enacted and managed by the CAICO. The DoD also declined to change the rule to extend the certification timeline to 4 years for those earning a certification prior to completion of rulemaking. Additionally, the DoD did not accept the recommendation to remove the requirement for providing documentation in the English language, which applies to all official information that would be provided to the CAICO, CMMC AB, or the DoD. The DoD disagreed with a commenter's recommendation to remove the second sentence in § 170.11(b)(7) that prohibits individual assessors from using any IT other than that provided to them by the C3PAO that has been contracted to perform that OSA's assessment. This sentence is required to eliminate ambiguity, particularly for C3PAOs that may have implemented a BYOD program or that allow some work roles to use personal devices. The DoD updated the rule to provide additional clarity. The DoD does not concur with the comment calling for a DoD Manual 8140.03 requirement on CCAs. Assessment teams are required to have a Lead Assessor who must meet the higher level of the DoDM 8140.03 requirements. The rule has been updated to remove reference to DoD Manual 8570. The experience requirements referenced for the Lead CCA are cumulative. The rule has been updated to move Lead CCA requirements to the end of § 170.11, but not to create a new section.

because granting access to information that is properly classified pursuant to E.O. 12958 , as implemented by DoD 5200.1-R, may cause damage to the national security. (11) System identifier and name. DUSP 11, POW/Missing Personnel Office Files. (i) Exemption. Information classified under E.O. 12958 , as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (ii) Authority. 5 U.S.C. 552a(k)(1) . (iii) Reasons. From subsection 5 U.S.C. 552a(d) because granting access to information that is properly classified pursuant to E.O. 12958 , as implemented by DoD 5200.1-R, may cause damage to the national security. (12) System identifier and name. DFOISR 05, Freedom of Information Act Case Files. (i) Exemption. During the processing of a Freedom of Information Act request, exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those ·other· systems of records are entered into this system, the Office of the Secretary of Defense claims the same exemptions for the records from those ·other· systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security

clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (13) System identifier and name. DFOISR 10, Privacy Act Case Files. (i) Exemption.

Offerors and contractors must report cyber incidents on unclassified networks or information systems, within cloud computing services, and when they affect contractors designated as providing operationally critical support, as required by statute. a. The clause at DFARS 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, covers cyber incident reporting requirements for incidents that affect a covered contractor information system or the covered defense information residing therein, or that affects the contractor's ability to perform the requirements of the contract that are designated as operationally critical support and identified in the contract. b. DFARS provision 252.204-7008, Compliance with Safeguarding Covered Defense Information Controls, requires an offeror that proposes to vary from any of the security controls of National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 in effect at the time the solicitation is issued to submit to the contracting officer a written explanation of how the specified security control is not applicable or an alternative control or protective measure is used to achieve equivalent protection. c. DFARS provision 252.239-7009, Representation of Use of Cloud Computing, requires contractors to report that they anticipate or do not anticipate utilizing cloud computing service in performance of the resultant contract. The representation will notify contracting officers of the applicability of the cloud computing requirements at DFARS clause 252.239-7010 of the contract. d. DFARS clause 252.239-7010, Cloud Computing Services, requires reporting of cyber incidents that occur when DoD is purchasing cloud computing services. These DFARS provisions and clauses facilitate mandatory cyber incident reporting requirements in accordance with statutory regulations. When reports are submitted, DoD will analyze the reported information for cyber threats and vulnerabilities in order to develop response measures as well as improve U.S. Government understanding of advanced cyber threat activity. In addition, the security requirements in NIST SP 800-171 are specifically tailored for use in protecting sensitive information residing in contractor information systems and generally reduce the burden placed on contractors by eliminating Federal-centric processes (printed page 36832) and requirements. The information provided will inform the Department in assessing the overall risk to DoD covered defense information on unclassified contractor systems and networks. Jennifer D. Johnson, Editor/Publisher, Defense Acquisition Regulations System. [FR Doc. 2022-13233 Filed 6-17-22; 8:45 am] BILLING CODE 5001-06-P

(2) Consider the following: (i) The relationship of each item of information retained and collected to the purpose for which the system is maintained; (ii) The specific impact on the purpose or mission of not collecting each category of information contained in the system; (iii) The possibility of meeting the informational requirements through use of information not individually identifiable or through other techniques, such as sampling; (iv) The length of time each item of personal information must be retained; (v) The cost of maintaining the information; and (vi) The necessity and relevancy of the information to the purpose for which it was collected. (g) Discontinued information requirements. (1) Stop collecting immediately any category or item of personal information for which retention is no longer justified. Also delete this information from existing records, when feasible. (2) Do not destroy any records that must be retained in accordance with disposal authorizations established under 44 U.S.C. 3303a , Examination by Archivist of Lists and Schedules of Records Lacking Preservation Value; Disposal of Records. § 310.11 Standards of accuracy. (a) Accuracy of information maintained. Maintain all personal information used or may be used to make any determination about an individual with such accuracy, relevance, timeliness, and completeness as is reasonably necessary to ensure fairness to the individual in making any such determination. (b) Accuracy determinations before dissemination. Before disseminating any personal information from a system of records to any person outside the Department of Defense, other than a Federal Agency, make reasonable efforts to ensure the information to be disclosed is accurate, relevant, timely, and complete for the purpose it is being maintained (see § 310.21(d)). § 310.12 Government contractors. (a) Applicability to government contractors. (1) When a DoD Component contract requires the operation or maintenance of a system of records or a portion of a system of records or (printed page 18764) requires the performance of any activities associated with maintaining a system of records, including the collection, use, and dissemination of records, the record system or the portion of the record system affected are considered to be maintained by

the DoD Component and are subject to this part. The Component is responsible for applying the requirements of this part to the contractor. The contractor and its employees are to be considered employees of the DoD Component for purposes of the criminal provisions of 5 U.S.C 552a(i) during the performance of the contract. Consistent with the Federal Acquisition Regulation (FAR), Part 24.1, contracts requiring the maintenance or operation of a system of records or the portion of a system of records shall include in the solicitation and resulting contract such terms as are prescribed by the FAR.

(Comment 70) Two comments state that many nontransporters own trucks or other vehicles and transport food as an incidental part of their operations. For example, many food distributors deliver food by truck to their customers and also may transport food returns. These entities should not be classified as transporters for their distribution practices that are incidental to the nontransporters' holding, processing, packing, importing, or receiving of food. The comments ask that the final rule clarify that an entity is either a transporter or a nontransporter, and that FDA will not consider the same entity a transporter for some purposes and a nontransporter for other purposes. The final rule should confirm that a food distributor is a nontransporter. A food distributor should not automatically be considered a transporter simply because it delivers food using its own truck fleet. If FDA were to consider the same company a transporter for some purposes and a nontransporter for other purposes, this would create tremendous confusion regarding what records are required to be retained. (Response) Both the proposed and final rule define a transporter as a person who has possession, custody, or control of an article of food for the sole purpose of transporting the food. A person who owns food, or who holds, processes, packs, imports, receives, or distributes food for purposes other than transportation is not a transporter, even if the person also transports food. In the example presented in the comment, a manufacturer that owned its own trucks to deliver food would not be considered a transporter. However, because FDA has exempted all foreign persons except those who transport food in the United States from this rule, foreign persons who transport food in the United States are subject to the requirements applicable to transporters regardless of whether that person has possession, custody, or control of the food for the sole purpose of transporting that food. (Comment 71) One comment states that the proposed definition of 'nontransporter' reads as follows: 'Nontransporter means a person who owns food or who holds, processes, packs * * *. The same reference to a 'person' is included in the definitions of 'nontransporter immediate previous source' and 'nontransporter immediate subsequent recipient.' The comment asks whether the proposed rules apply to firms and other legal entities and/or physical persons. Any other solution would, in the comment's view, neither be appropriate nor practicable. (Response) The maintenance and inspection of records provisions in section 306 of the Bioterrorism Act apply to 'persons (excluding farms and restaurants) who manufacture, process, pack, transport, distribute, receive, hold, or import food.' The term 'person' has the same meaning as in section 201(e) of the FD&C Act and includes individuals, partnerships, corporations, and associations.

The DoD declined to delete text stating that OSAs may elect to complete a self-assessment or pursue CMMC certification assessment to distinguish themselves as competitive because the recommendation did not result in a substantive change. CMMC rule describes anticipated impacts on the DIB in the Impact and Cost Analysis section. Speculation on market forces affecting the DIB is outside of the scope of the CMMC program. Speculation on market forces affecting CMMC (printed page 83128) ecosystem CCP and CCA roles are also outside of the scope of the CMMC program. Likewise, limitations on career opportunities and associated issues such as burn-out or job satisfaction are beyond the scope of the program. The DoD declines to comment on external market factors impacting CMMC compliance. The seven-year timespan reflects the DoD's estimate for all DIB members to achieve CMMC compliance. The implementation plan ramps up CMMC assessment requirements over 4 phases, such that the ecosystem will reach maximum capacity by year four. The DoD does not agree with commenter assertions that 70,000 or more entities will require CMMC Level 2 assessment by October 1, 2026. Table 6 of the Impact and Cost Analysis of CMMC 2.0 section provides the DoD's estimate of CMMC assessment numbers by year and level. DoD considered many alternatives before deciding upon the current CMMC structure. By design, the CMMC program depends on the supply and demand dynamics of the free market, enabling it to naturally scale and adapt to capacity requirements. Planned changes to DCMA staffing levels have been considered with regard to implementation of CMMC Level 3 and C3PAO assessments as described in this rule. The DIBCAC will communicate extensively with contractors about the conduct of a Level 3 assessment during the pre-assessment planning phase. 15. Assessments a. Level 1 and Mapping of 15 Level 1 to 17 Level 2 Requirements Comment: A few questions were submitted about CMMC level 1 requirements, on topics such as whether DoD intended affirmations for

CMMC level 1 be required annually versus triennially, and whether specific policies and procedures documentation is required for Level 1 self-assessments. One commenter asked about limits on deficiency remediation and re-accomplishing an assessment in the event a company fails a CMMC Level 1 self-assessment. Another commenter asked for the specific wording to reflect a CMMC Level 1 assessment score in SPRS.

As in other contexts, the Government may specify additional guidance in the solicitation. CMMC assessments will be identified as pre-award requirements. Subcontractors at each tier are responsible for submitting their own assessment and affirmation information in SPRS. CMMC self-assessments and certifications will be reflected in SPRS, including an indicator of the currency of the credentials. Contracting Officers and Program Managers need not review any assessment artifacts, only the resulting scores and certificate validity period. Work arrangements between the prime and subcontractor are beyond the scope of this rule, however, if CUI is flowed down and will be processed, stored, or transmitted on subcontractor information systems in the performance of a DoD contract then CMMC requirements also flow down as described in § 170.23. The DoD will not track progress toward certification but will implement CMMC as a pre-award requirement. An OSA's pursuit of a C3PAO assessment is a business decision to be made by each contractor considering the contract opportunities it wishes to pursue. The DoD disagrees with one commenter's assertion that CMMC requirement will flow down regardless of what work they do, because it does not acknowledge the point that flow-down requirements are for subcontractors who process, store, or transmit CUI. The text of § 170.23, clearly conditions the flow-down to those cases when a subcontractor will process, store, or transmit FCI or CUI. The prime contractor's responsibility is to flow down CMMC assessment requirements as described in § 170.23 and to ensure that FCI and CUI are not further disseminated to subcontractors that do not meet the CMMC requirement indicated in § 170.23. Likewise, subcontractors must also flow down CMMC requirements and ensure that FCI and CUI are not further disseminated to subcontractors that do not meet the CMMC requirement indicated in § 170.23. Section 170.23 has been revised to make this clearer. DoD declines to accept the recommendation to treat CUI like classified data. Classified information is managed differently from CUI, and different safeguarding regulations apply to these different categories of information (each of which are defined in 32 CFR part 2002). This rule makes no change to CUI policies for marking of data, and CMMC levels are not CUI categories in the DoD CUI registry. Primes and their subcontractors must understand flow-down requirements based on § 170.23, which clearly identifies requirements that apply when subcontractors will process, store, or transmit CUI in performance of the subcontract and the Prime contractor has a requirement of Level 3 certification assessment (i.e.,

(F) From subsections (e)(4)(G), (e)(4)(H), and (e)(4)(I) (Agency Requirements) and (f) (Agency Rules), because portions of this system are exempt from the individual access provisions of subsection (d) for the reasons noted above, and therefore NGA is not required to establish requirements, rules, or procedures with respect to such access. Providing notice to individuals with respect to existence of records pertaining to them in the (printed page 14784) system of records or otherwise setting up procedures pursuant to which individuals may access and view records pertaining to themselves in the system would undermine investigative efforts and reveal the identities of witnesses, and potential witnesses, and confidential informants. (G) From subsection (e)(5) (Collection of Information) because with the collection of information for law enforcement purposes, it is impossible to determine in advance what information is accurate, relevant, timely, and complete. Compliance with subsection (e)(5) would preclude NGA personnel from using their investigative training and exercise of good judgment to both conduct and report on investigations. (H) From subsection (e)(8) (Notice on Individuals) because compliance would interfere with NGA's ability to cooperate with law enforcement who would obtain, serve, and issue subpoenas, warrants, and other law enforcement mechanisms that may be filed under seal and could result in disclosure of investigative techniques, procedures, and evidence. (I) From subsection (g)(1) (Civil Remedies) to the extent that the system is exempt from other specific subsections of the Privacy Act. (4) System identifier and name. NGA-008, National Geospatial-Intelligence Agency Polygraph Records System. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (a)(4)(i). When claimed, this exemption allows limited protection of investigative

reports maintained in a system of records used in personnel or administrative actions. (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. Pursuant to 5 U.S.C. 552a(k)(2) , the Director of NGA has exempted this system from the following provisions of the Privacy Act, subject to the limitation set forth in 5 U.S.C. 552a(c)(3) ; (d); (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I); and (f). Exemptions from these particular subsections are justified, on a case-by-case basis to be determined at the time a request is made, for the following reasons:

Review and periodically update a risk analysis in response to changes in the environment and/or operations, security incidents, or occurrence of a significant event. Conduct risk analyses consistent with policies and procedures. Failing to document any efforts to develop, maintain, and update policies and procedures for conducting risk analyses was common. For example, health care providers commonly submitted documentation of some security activities performed by a third-party security vendor, without submitting documentation of any risk analysis that served as the basis of such activities. [475] Many regulated entities used and relied on outside persons to manage or perform risk analyses for their organizations; however, these outside persons frequently failed to meet the requirements of the Security Rule. Regulated entities also frequently and incorrectly assumed that a purchased security product satisfied all of the Security Rule's requirements. The responsibility to maintain an appropriate risk analysis rests with the regulated entity. Accordingly, it is essential that regulated entities understand and comply with risk analysis requirements to appropriately safeguard PHI. Numerous OCR investigations reflect the failure of regulated entities to develop and implement holistic risk analysis programs. For example, OCR's investigation of a health system in the aftermath of a ransomware attack found evidence of potential failures to: conduct a compliant risk analysis to determine the potential risks and vulnerabilities to ePHI in its systems; implement a contingency plan to respond to emergencies, like a ransomware attack, that damage systems that contain ePHI; and implement policies and procedures to allow only authorized users access to ePHI. [476] In another recently concluded investigation involving a large medical center, the covered entity reported that over a seven-month period, one of its employees inappropriately accessed the ePHI of more than 12,000 patients and then sold certain patient information to an identity theft ring. [477] OCR's investigation indicated potential violations of the requirement to conduct an accurate and thorough risk analysis of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of all of the ePHI held by the medical center, as well as the requirement at 45 CFR 164.308(a)(1)(ii)(D) to implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking. In another case, the OCR settled a ransomware cyberattack investigation with a business associate. [478] The cyberattack affected the ePHI of over (printed page 941)

(C) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (D) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (E) From subsection (e)(2) because in a criminal investigation the requirement that information be collected to the greatest extent possible from the subject individual would present a serious impediment to law enforcement in that the subject of the investigation would be placed on notice of the existence of the investigation and would therefore be able to avoid detection. (F) From subsection (e)(3) because the requirement that individuals supplying information be provided with a form stating the requirements of subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (G) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (H) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (I) From subsection (e)(5) because in the collection of information for law enforcement purposes it is impossible to determine in advance what information

is accurate, relevant, timely, and complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light and the accuracy of such information can only be determined in a court of law. The restrictions of subsection (e)(5) would restrict the ability of trained investigators and intelligence analysts to exercise their judgment in reporting on investigations and impede the development of intelligence necessary for effective law enforcement.

3.6.1 | Judgment Selection ... 3.6.1 Judgment Selection To record an element judgment, the appropriate option (radio) button to the right of the element text area is clicked.

CIS Safeguard 10.6 · Centrally Manage Anti-Malware Software Centrally manage anti-malware software. Implementation Groups: 2,3 Asset Type: devices Security Function: protect Parent Control: Malware Defenses

a broad spectrum of activities including many different engineering disciplines, computer programming, systems analysis, mathematics, management, information technology auditing, privacy, and law. Members also have an extensive history of professional publications, and professional journalism. Members have worked (and in many cases, continue to work) on the development and evolution of some of the most important pieces of information security and privacy legislation in the federal government, including the Privacy Act of 1974, the Computer Security Act of 1987, the E-Government Act (including FISMA), and other e-government services and initiatives.

This year the Computer Security Division (CSD) continued its efforts to improve information system security. This effort was accomplished through raising awareness of information technology risks, vulnerabilities, and protection requirements-particularly for new and emerging technologies. We continued to research, study, advise Agencies of IT vulnerabilities, and devise techniques for the cost-effective security and privacy of sensitive Federal systems. We continued to develop standards, metrics, tests, and validation programs to promote, measure, and validate security in systems and services. We also developed guidance to increase secure IT planning, implementation, management, and operation. This effort was conducted to assist our everexpanding customer base that now includes federal, state, and local governments, the healthcare community, colleges and universities, small businesses, the private sector, and the international community. - Methods for assessing effectiveness of security requirements - SP 800-53A, Guide for Assessing the Security Controls in Federal Information Systems (first public draft issued July 2005). - Procedures for capturing results of security requirement assessments and results of security program assessments - SP 800-26 Revision 1, Guide for Information Security Program Assessments and System Reporting Form (first public draft issued August 2005). - Bring the security planning process up to date with key standards and guidelines developed by NIST - SP 800-18 Revision 1, Guide for Developing Security Plans for Federal Information Systems (first public draft issued August 2005).

The Global Sourcing team is responsible for traditional SCRM. While SCRM is formally dedicated to this team, the Consumer Electronics Company encourages open communication for concerns relating to product integrity and risk. The company considers broad executive attention an important component for handling supply chain risk and leadership roles with formal SCRM responsibilities, including the CEO, CFO, VP of Global Sourcing, and Director of Information Technology. In particular, the internal information technology team works directly with Global Sourcing to mitigate potential cybersecurity threats presented by suppliers and upstream components. As the Consumer Electronics Company's business as an automobile OEM supplier continues to grow, downstream customer requirements are driving the company to mature their supply chain program. In 2015, Fiat Chrysler recalled 1.4 million cars ii after Wired Magazine iii revealed that a cybersecurity vulnerability exposed affected vehicles to remote control, allowing an attacker to manipulate steering, braking, and audio systems. The resulting public attention led to greater investment in C-SCRM throughout the auto industry. The industry's enhanced requirements for the Consumer Electronics Company and other suppliers include stronger controls for upstream supply partners, highlighting the value of the company's CTPAT participation.

7-12 7-12 7-13 7-13 7-13 7-13 Design Standards o 7-14 Organization Control . 7-14 Access Control . 7-15 Phase Review/Project Control Testing/System Assurance ^ 7-16 7-16 Promotion Process Documentation 7-17 7-17 Auditor/Independent Party Involvement Configuration Management 7-17 Emergency Procedures 7-18 categories: physical, system and

administrative. The physical controls include the traditional "put the system in a vault" measures, including perimeter control, hazard protection and backup mechanisms. System controls include hardware/software access control techniques, program integrity measures, audit trail techniques and failure response procedures. Administrative control techniques include what are commonly referred to as Change Control Procedures. Control techniques must be evaluated against each of the access control, accuracy, and availability factors and an overall score must be arrived at for each of those factors. Development procedures - standards, configuration management, certification, etc.

Public Law 96-511, Paperwork Reduction Act (44 U.S.C. Chapter 35) Notwithstanding any other provision of law, no person is required to respond to, nor is subject to a penalty for failure to comply with, a collection of information, subject to the requirements of the Paperwork Reduction Act of 1995 (44 U.S.C. 3501 et seq.) (PRA), unless that collection of information displays a currently valid Office of Management and Budget (OMB) Control Number. This proposed rule involves collections previously approved by OMB under the following control numbers. OMB Control Number: 0704-0194, DD Form 441, Department of Defense Security Agreement OMB Control Number: 0704-0571, National Industrial Security System OMB Control Number: 0704-0567, DoD Contract Security Classification Specification OMB Control Number: 0704-0573, Defense Information System for Security (DISS) OMB Control Number: 0704-0579, Certificate Pertaining to Foreign Interests, SF 328 OMB Control Number: 3150-0047, 10 CFR part 95 , Facility Security Clearance and Safeguarding of National Security Information and Restricted Data OMB Control Number: 1910-1800, Security DoD believes the total burden hours associated with these collections are not expected to change based on the amendments proposed in this rule. Information on the current version of these collections, including all supporting materials, can be obtained at <https://www.reginfo.gov/public/do/PRAMain> and typing in the OMB control number. Section 202, Public Law 104-4 , Unfunded Mandates Reform Act. Section 202 of the Unfunded Mandates Reform Act of 1995 (UMRA) (2 U.S.C. 1532) requires agencies to assess anticipated costs and benefits before issuing any rule whose mandates require spending in any one year of \$100 million in 1995 dollars, updated annually for inflation. This rule will not mandate any requirements for State, local, or tribal governments, nor will it affect private sector costs. Executive Order 13132 , Federalism. E.O. 13132 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct requirement costs on State and local governments, preempts State law, or otherwise has Federalism implications. This rule will not have a substantial effect on State and local governments. Executive Order 13175 , Consultation and Coordination With Indian Tribal Governments. Executive Order 13175 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct compliance costs on one or more Indian tribes, preempts tribal law, or affects the distribution of power and responsibilities between the federal government and Indian tribes. This rule will not have a substantial effect on Indian tribal governments. List of Subjects in 32 CFR Part 117 Classified information; Government contracts; USG contracts National Industrial Security Program (NISP); Prime contractor Subcontractor

3.1.1. 3.1.1): A memorizable secret typically chosen by the subscriber Look-up secret (Sec. 3.1.1) or a biometric comparison: Look-up secret (Sec.

Under the CMMC Assessment Process (CAP) v2.0: ****Conditional certification****: Issued when an organization meets most CMMC Level 2 requirements but has a limited number of NOT MET findings with approved POA&M entries. The organization must remediate all POA&M items within 180 days and undergo a closeout assessment to achieve final certification. ****Final certification****: Issued when all 110 NIST SP 800-171 requirements are assessed as MET (or when all POA&M items from a conditional certification are closed). The final certification is valid for three years. Key points: - Not all gaps qualify for POA&M treatment. Critical security controls may need to be fully implemented before any certification is issued. - The C3PAO makes the certification recommendation; the Cyber AB issues the certification. - Organizations should aim for full implementation before the assessment to avoid the risk and cost of a conditional certification and closeout.

, (k)(2), or (k)(5) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(1) , (k)(2), or (k)(5). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning

the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (26) System identifier and name. A0381-20b DAMI, Foreign Intelligence/Counterintelligence/Information Operations/Security Files. (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958, as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (B) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance (printed page 14758) of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source.

case record, the NGB hereby claims the same exemptions for the records from those other systems that are entered into this system, as claimed for the original primary SOR which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2), (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this SOR. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of (printed page 14786) Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a. (2) System identifier and name. INGB 005, Special Investigation Reports and Files. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information except to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (e)(2)(i). When claimed, this exemption allows limited protection of investigative reports maintained in a SOR used in personnel or administrative actions. Any portion of this SOR which falls within the provisions of 5 U.S.C. 552a(k)(2) may be exempt from the following subsections of 5 U.S.C. 552a: (c)(3), (d), (e)(1), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2). (iii) Reasons. (A) From subsection (c)(3) of 5 U.S.C. 552a because to grant access to the accounting for each disclosure as required by 5 U.S.C. 552a

3.3.1 | Data Recording | 3-13 | 3.3.1 Data Recording Audit data is recorded from several sources (such as the logon host's operating system or a remote application) to produce a complete picture of a user's security relevant actions.

The Department also considered proposing to permit small and rural health care providers to adopt

alternate compensating controls, in lieu of the specified implementation specifications, to meet certain standards. After careful consideration, the Department concluded that it potentially could be just as costly to identify and adopt compensating controls that are reasonable and appropriate for small and rural health care practices. Small and rural health care providers would likely need to either hire personnel or contract with cybersecurity experts to identify potential compensating controls that would meet the relevant standard and provide implementation support. Accordingly, the Department declines to put forward such proposals at this time. The Federal Information Security Modernization Act The Department considered the requirements of the Federal Information Security Modernization Act (FISMA) [992] and whether compliance with FISMA by Federal agencies that are also regulated entities would be comparable to meeting the proposals in this NPRM. FISMA requires each Federal agency to develop, document, and implement an agency-wide program to provide information security for the information and information systems that support the operations and assets of the agency, including those provided or managed by another agency, contractor, or other source. [993] After careful consideration, the Department does not believe that a regulated entity's compliance with FISMA would necessarily ensure compliance with all applicable proposed requirements in this NPRM because FISMA's requirements and the Security Rule's requirements are designed to serve different purposes. FISMA primarily focuses on securing Federal information systems, while the Security Rule applies specifically to ePHI. This NPRM contains specific proposed requirements, not found in FISMA, which are tailored to ensure the confidentiality, integrity, and availability of ePHI. Therefore, although the Department believes that FISMA requirements are consistent with those in the Security Rule and the proposals in this NPRM, we decline to propose that compliance with FISMA requirements would be a comparable alternative to compliance with the proposals in this NPRM. Instead, we believe that FISMA requirements complement the Security Rule and the proposed requirements and will facilitate the ability of regulated entities that are also subject to FISMA to fulfill their compliance with the HIPAA Rules. Modifications to the Definition of Information System The Department considered proposing additional modifications to the definition of information system. The Security Rule currently defines the term information system as an interconnected set of information resources under the same direct management control that shares common functionality and includes hardware, software, information, data, applications, communications, and people. [994]

We recognize that small and rural health care providers may have needs and capabilities that differ from those of other regulated entities. For example, small health care providers and rural health care providers are often located at a greater distance from other health care providers. [293] It may be more challenging for them to attract and retain clinicians and administrative support staff. [294] They also face difficulty attracting and retaining security experts and must make difficult decisions regarding investments in competing priorities. [295] Often, preparation for security incidents or other occurrences that adversely affect the confidentiality, integrity, or availability of ePHI is neglected in favor of other priorities, putting small and rural health care providers at greater risk for such an occurrence. [296] We continue to believe that it is just as important for small and rural health care providers to implement strong security measures as it is for larger health care providers and other categories of regulated entities. According to experts, Cybercriminals go after small businesses, especially those in the healthcare industry, (printed page 919) because they are easy targets. [297] In 2017, 93 percent of small rural and critical access hospitals and 86 percent of physician offices relied on health IT to inform their clinical practice. [298] And yet, small health care providers are less likely than a larger organization to even have a designated security or compliance officer. [299] Smaller practices and rural and community facilities also may be more likely to rely on older technologies that are no longer supported by security patches and updates, including medical devices such as insulin pumps and pacemakers in which inaccuracies or errors could affect patient safety. [300] Thus, small health care providers are at the greatest risk of a breach. [. .] Smaller, rural practice settings are especially high-risk target areas for a breach. [301] According to an expert who speaks to and works with health care providers on IT services and cybersecurity, small health care providers are more susceptible because they do not have a lot of the tools and security measures necessary to protect themselves. [302] For example, a critical access hospital in Colorado recovered from a cyberattack in 2019, but it required an incredible amount of staff time, many months of recovery efforts, and an enormous financial outlay to restore systems and prevent another attack. [303] In fact, the hospital estimates that it took a full year of a staff person's time to complete the recovery and protect the organization for the future. [304] These costs do not include the multiple ransoms paid to the attackers after the first set of keys

(17) Maintain all facilities, personnel, and equipment involved in CMMC activities that are in scope of their CMMC Level 2 assessment and comply with all security requirements and procedures as prescribed by the Accreditation Body. (18) Upload into the CMMC instantiation of eMASS assessment data compliant with the CMMC assessment data standard as set forth in eMASS CMMC Assessment Import Templates on the CMMC eMASS website: <https://cmmc.emass.apps.mil> . [1] (19) Issue certificates of assessment to OSCs in accordance with the certification requirements set forth in § 170.17. (20) Address all OSC appeals arising from CMMC Level 2 assessment activities. Any appeal not resolved by the C3PAO will elevate to the Accreditation Body for final determination. (21) Submit assessment appeals, review records, and decision results of assessment appeals to DoD using the CMMC instantiation of eMASS. § 170.10 CMMC Assessor and Instructor Certification Organization (CAICO). (a) Roles and responsibilities. The CAICO is responsible for training, testing, authorizing, certifying, and recertifying CMMC assessors, instructors, and related professionals. Only the CAICO may make decisions relating to examination certifications, including the granting, maintaining, recertifying, expanding, and reducing the scope of certification, and suspending or withdrawing certification in accordance with current ISO/IEC 17024:2012 (incorporated by reference, see § 170.2). At any given point in time, there will be only one CAICO for the DoD CMMC Program. (b) Requirements. The CAICO shall: (1) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17); and achieve and maintain full compliance with ISO/IEC 17024:2012 within 25 months of registration. If ISO/IEC 17024:2012 is revised or superseded, the CAICO shall achieve full compliance with the updated standard within 12 months of the date of revision. (2) Provide all documentation and records in English. (3) Train, test, certify, and recertify CCAs, CCIs, and CCPs in accordance with the requirements of this section. (4) The CAICO's certification examinations must be certified under ISO/IEC 17024:2012, or subsequent revisions, by a recognized U.S.-based accreditor who is not a member of the CMMC Accreditation Body and complies with ISO/IEC 17011:2017, or subsequent revisions. (5) Establish quality control policies and procedures for the generation of training products, instruction, and testing materials. (6) Oversee development, administration, and management pertaining to the quality of training and examination materials for CMMC assessor and instructor certification and recertification. (7) Establish and publish an authorization and certification appeals process to receive, evaluate, and make decisions on complaints and appeals in accordance with ISO/IEC 17024:2012, or subsequent revisions.

DFARS 252.204-7020 (NIST SP 800-171 DoD Assessment Requirements) Requires contractors to have current NIST SP 800-171 DoD Assessment for Medium and High assessment levels. Flow-down requirements: DFARS 252.204-7020 includes flow-down provisions requiring prime contractors to include the clause in subcontracts where CUI will be processed, stored, or transmitted. Subcontractors must meet the same security requirements as the prime.

(1) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17); and achieve and maintain ISO/IEC 17024(E) accreditation within 12 months of December 16, 2024. (2) Provide all documentation and records in English. (3) Train, test, and designate PIs in accordance with the requirements of this section. Train, test, certify, and recertify CCPs, CCAs, and CCIs in accordance with the requirements of this section. (printed page 83224) (4) Ensure the instructor and assessor certification examinations are certified under ISO/IEC 17024:2012(E) (incorporated by reference, see § 170.2), by a recognized US-based accreditor who is not a member of the CMMC Accreditation Body. The US-based accreditor must be a signatory to International Laboratory Accreditation Cooperation (ILAC) or relevant International Accreditation Forum (IAF) Mutual Recognition Arrangement (MRA) and must operate in accordance with ISO/IEC 17011:2017(E) (incorporated by reference, see § 170.2). (5) Establish quality control policies and procedures for the generation of training products, instruction, and testing materials. (6) Oversee development, administration, and management pertaining to the quality of training and examination materials for CMMC assessor and instructor certification and recertification. (7) Establish and publish an authorization and certification appeals process to receive, evaluate, and make decisions on complaints and appeals in accordance with ISO/IEC 17024:2012(E) (incorporated by reference, see § 170.2). (8) Address all appeals arising from the CCA, CCI, and CCP authorizations and certifications process through use of internal processes in accordance with ISO/IEC 17024:2012(E) (incorporated by reference, see § 170.2). (9) Maintain records for a period of six (6) years of all procedures, processes, and actions related to

fulfillment of the requirements set forth in this section and provide the Accreditation Body access to those records. (10) Provide the Accreditation Body information about the authorization and accreditation status of assessors, instructors, training community, and publishing partners. (11) Ensure separation of duties between individuals involved in testing activities, training activities, and certification activities. (12) Safeguard and require any CAICO training support service providers, as applicable, to safeguard the confidentiality of applicant, candidate, and certificate-holder information and ensure the overall security of the certification process. (13) Ensure that all PII is encrypted and protected in all CAICO information systems and databases and those of any CAICO training support service providers. (14) Ensure the security of assessor and instructor examinations and the fair and credible administration of examinations.

CMMC does not require implementation of any additional security protection requirements beyond those identified in current FAR clause 52.204-21 and in NIST SP 800-171 R2 for CMMC Levels 1 and Level 2, respectively. CMMC Level 3 requirements are new and based upon NIST SP 800-172 Feb2021. Steps Taken To Minimize Additional Cost of Credit The DoD is not a covered agency under 5 U.S.C. 604 . E. Public Law 96-511, Paperwork Reduction Act (44 U.S.C. Chapter 35) Sections of this rule contain information collection requirements. As required by the Paperwork Reduction Act (44 U.S.C. Chapter 35), DoD has submitted information collection packages to the Office of Management and Budget for review and approval. The titles and proposed OMB control numbers are as follows. Cybersecurity Maturity Model Certification (CMMC) Enterprise Mission Assurance Support-Service (eMASS) Instantiation Information Collection (OMB control number 0704-0676). Cybersecurity Maturity Model Certification (CMMC) Program Reporting and Recordkeeping Requirements Information Collection (OMB Control Number 0704-0677). In the proposed rule, DoD invited comments on these information collection requirements and the paperwork burden associated with this rule. Five comments were received on the information clearance packages that were not applicable to the information collection requirements; however, the comments were applicable to other aspects of the rule, and they are addressed in the comments section of this preamble. There were no changes to paperwork burden included in the proposed rule that published December 26, 2023 (88 FR 89058) based on public comments received. To review these collections including all background materials please visit at <https://www.reginfo.gov/public/do/PRAMain> and use the search function to enter either the title of the collection or the OMB Control Number. F. Executive Order 13132 , Federalism Executive Order 13132 establishes certain requirements that an agency must meet when it promulgates a final rule that imposes substantial direct requirement costs on state and local governments, preempts state law, or otherwise has federalism implications. This final rule will not have a substantial effect on State and local governments. G. Executive Order 13175 , Consultation and Coordination With Indian Tribal Governments Executive Order 13175 establishes certain requirements that an agency must meet when it promulgates a final rule that imposes substantial direct compliance costs on one or more Indian Tribes, preempts Tribal law, or effects the distribution of power and responsibilities between the Federal Government and Indian Tribes. This final rule will not have a substantial effect on Indian Tribal governments. List of Subjects in 32 CFR Part 170 Certification CMMC CMMC Levels CMMC Program Contracts Controlled unclassified information Cybersecurity Federal contract information Government procurement Incorporation by reference Accordingly, the Department of Defense adds 32 CFR part 170

When providing cryptographic key services under the contract, paragraph (j) of the clause 52.239-YY requires contractors to provide the agency with applicable key material and services; however, the Government reserves the right to implement and operate its own cryptographic key services under the contract. Operational Technology Equipment List. Paragraph (k) of the clause 52.239-YY requires contractors to develop and maintain a list of the physical location of all operational technology equipment included within the boundary for the non-cloud FIS and provide a copy to the Government, upon request. While the proposed rule does not specify a format for the operational technology equipment list, contractors must ensure that the list includes enough information about the equipment to positively locate and track any movement of the equipment during contract performance, including details on password protection and the ability for remote access to the equipment. Binding Operational Directives and Emergency Directives. Paragraph (l) of clause 52.239-YY advises that contractors must comply with Binding Operational Directives (BODs) and Emergency Directives (EDs) issued by CISA that have specific applicability to a FIS used or operated by a contractor. A list of BODs and EDs can be found at <https://www.cisa.gov/directives> . Occasionally, a BOD or ED with an explicit applicability to a FIS used or operated by a contractor will not need to apply to a contract. In such situations, the contracting officer will identify, in paragraph (l)(2) of the

clause, any such BODs or EDs that are not applicable to the contract. Indemnification. Paragraph (m) of the clause 52.239-YY indemnifies the Government from any liability that arises out of the performance of the contract and is incurred because of the contractor's introduction of certain information or matter into Government data or the contractor's unauthorized disclosure of certain information or material. The paragraph serves as a waiver of defense to change the analysis from negligence, which is the defense, to strict liability, which doesn't allow for a defense. The paragraph also provides terms and requirements in the event of a claim or suit against the Government for such an unauthorized disclosure or introduction of data or information. The proposed text was taken from industry terms of service agreements for cloud services providers. Subcontracts. Paragraph (n) of the clause 52.239-YY advises contractors that the substance of the clause must be included in any subcontracts issued under the contract that are for services to develop, implement, operate, or maintain a FIS using non-cloud computing services. Prohibition on IoT Devices. The rule also implements a portion of the Internet of Things Cybersecurity Improvement Act of 2020 (Pub. L. 116-207

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Health and Human Services Food and Drug Administration [Docket No. FDA-2023-N-3636] AGENCY: Food and Drug Administration, HHS. ACTION: Notice; request for comment. SUMMARY: The Food and Drug Administration (FDA or Agency) is announcing the availability of an information technology (IT) strategic plan entitled the FDA Information Technology Strategy and a request for comment on this IT Strategy. As part of our User Fee Program commitments and Omnibus Bill requirements, FDA will develop and publish an FDA Data and Technology Strategic Plan by September 29, 2023. This plan will define and shape the future course of FDA's data and technology capabilities, building on the existing FDA Modernization Framework. The plan will also integrate Agency and center strategies. DATES: Submit either electronic or written comments on the Strategy by October 30, 2023, to ensure that the Agency considers your comments on this Strategy for future iterations of the IT Strategy. ADDRESSES: You may submit comments as follows: (printed page 64436) Electronic Submissions Submit electronic comments in the following way: Federal eRulemaking Portal: <https://www.regulations.gov> . Follow the instructions for submitting comments. Comments submitted electronically, including attachments, to <https://www.regulations.gov> will be posted to the docket unchanged. Because your comment will be made public, you are solely responsible for ensuring that your comment does not include any confidential information that you or a third party may not wish to be posted, such as medical information, your or anyone else's Social Security number, or confidential business information, such as a manufacturing process. Please note that if you include your name, contact information, or other information that identifies you in the body of your comments, that information will be posted on <https://www.regulations.gov> . If you want to submit a comment with confidential information that you do not wish to be made available to the public, submit the comment as a written/paper submission and in the manner detailed (see Written/Paper Submissions and Instructions). Written/Paper Submissions Submit written/paper submissions as follows: Mail/Hand Delivery/Courier (for written/paper submissions): Dockets Management Staff (HFA-305), Food and Drug Administration, 5630 Fishers Lane, Rm. 1061, Rockville, MD 20852.

(iii) Minimum identifying data on logs, receipts, and destruction certificates will include the NATO reference number, short title, date of the document, classification, and serial copy numbers. Logs will reflect the short title, unclassified subject, and distribution of the documents. (iv) Receipts are required for all NATO classified documents except NATO CONFIDENTIAL. (v) Inventories will be conducted annually of all COSMIC TOP SECRET, NATO SECRET, and ATOMAL documents. (vi) Accountability records for ATOMAL documents will be retained for 10 years after transfer or destruction of the ATOMAL document. Destruction certificates will be retained for 10 years after destruction of the related ATOMAL documents. (19) Security violations and loss, compromise, or possible compromise. The contractor will immediately report the loss, compromise, or suspected loss or compromise, as well as any other security violations involving NATO classified information to the CSA. (20) Extracting from NATO documents. Permission to extract from a COSMIC TOP SECRET or ATOMAL document will be obtained from the CUSR. (i) If extracts of NATO information are included in a U.S. document prepared for a non-NATO contract, the document will be marked with U.S.

classification markings. The caveat, "THIS DOCUMENT CONTAINS NATO (level of classification) INFORMATION" also will be marked on the front cover or first page of the document. Additionally, each paragraph or portion containing the NATO information will be marked with the appropriate NATO classification, abbreviated in parentheses (e.g., "NS" for NATO SECRET) preceding the portion or paragraph. Declassification and downgrading instructions shall indicate that the NATO information is exempt from declassification or downgrading without the prior consent of NATO, in the absence of other originator instructions, citing the reason "Foreign Government Information." (ii) The declassification or downgrading of NATO information in a U.S. document requires the approval of the originating NATO activity. Requests will be submitted to the CUSR for NATO contracts, through the GCA for U.S. contracts, and through the CSA for non-NATO contracts awarded by a NATO member nation.

(21) Release of U.S. information to NATO. (i) Release of U.S. classified or export-controlled information to NATO requires an export authorization or other written disclosure authorization. When a document containing U.S. classified information is being prepared for NATO, the appropriate NATO classification markings will be applied to the document. (A) Documents containing U.S. classified information and U.S. classified documents that are authorized for release to NATO will be marked on the cover or first page "THIS DOCUMENT CONTAINS U.S. CLASSIFIED INFORMATION. THE INFORMATION IN THIS DOCUMENT HAS BEEN AUTHORIZED FOR RELEASE TO (cite the NATO organization) BY (cite the applicable license or other written authority)."

Phase 1: Planning and preparing for the self-assessment: \$14,426 A director (MGMT5) for 32 hours (\$190.52/hr x 32hrs = \$6,097) An external service provider (ESP) for 32 hours (\$260.28/hr x 32hrs = \$8,329) Phase 2: Conducting the self-assessment: \$15,542 A director (MGMT5) for 16 hours (\$190.52/hr x 16hrs = \$3,048) An external service provider (ESP) for 48 hours (\$260.28/hr x 48hrs = \$12,493) Phase 3: Reporting of self-assessment results into SPRS: \$2,851 A director (MGMT5) for 4 hours (\$190.52/hr x 4hrs = \$762) An external service provider (ESP) for 8 hours (\$260.28/hr x 8hrs = \$2,082) A staff IT specialist (IT4-SB) for 0.08 hours (\$86.24/hr x 0.08hrs = \$7) Affirmation: initial affirmation post assessment: \$ 1,459 Reaffirmations: It is estimated that the costs to reaffirm a Level 2 self-assessment annually is \$1,459 (three-year costs to reaffirm a Level 2 self-assessment annually is \$4,377, or \$1,459 x 3): A director (MGMT5) for 4 hours (\$190.52/hr x 4hrs = \$762) A staff IT specialist (IT4-SB) for 8.08 hours (\$86.24/hr x 8.08hrs = \$697) The Level 2 self-assessment and affirmations cost burden will be addressed as part of the 48 CFR part 204 CMMC Acquisition rule. Summary: The following is the annual small entities total cost summary for Level 2 self-assessments and affirmations over a ten-year period: (Example calculation, Year 2: (*\$34,277 self-assessment per entity x 101 entities) + (\$1,459 annual affirmation per entity x 20 entities) = \$3,491,193) All Entities Summary The following is a summary of the cost to all entities regardless of size for Level 2 self-assessments and affirmations over a ten-year period: (printed page 83185) CMMC Level 2 Certification Assessment and Affirmation Costs Other Than Small Entities Nonrecurring and recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with Level 2 certification assessment since it is assumed the contractor or subcontractor has implemented the NIST SP 800-171 R2 security requirements. Assessment and Initial Affirmation Costs: It is estimated that the cost to support a Level 2 certification assessment and annual affirmation for an "other than small" entity is \$112,345. The three-year cost is \$117,768 (as summarized in 4.1.2, table 9), and includes a triennial assessment + affirmation, plus two additional annual affirmations (\$112,345 + \$2,712 + \$2,712, with a minor rounding difference.) Phase 1: Planning and preparing for the certification assessment: \$26,264 A director (MGMT5) for 32 hours (\$190.52/hr x 32hrs = \$6,097) A manager (MGMT2) for 64 hours (\$95.96/hr x 64hrs = \$6,141) A staff IT specialist (IT4) for 72 hours (\$97.49/hr x 72hrs = \$7,019) A senior IT specialist (IT3) for 40 hours (\$81.96/hr x 40hrs = \$3,278) An IT specialist (IT2) for 58 hours (\$54.27/hr x 58hrs = \$3,148) An associate IT specialist (IT1) for 16 hours (\$36.32/hr x 16hrs = \$581) Phase 2: Conducting the certification assessment: \$28,600 A director (MGMT5) for 32 hours (\$190.52/hr x 32hrs = \$6,097)

(c) A computer matching agreement (CMA) shall be prepared by the Component, consistent with the requirements of § 310.53 of this subpart and submitted to the DPO. If the CMA satisfies the requirements of the Privacy Act (5 U.S.C. 552a) and OMB Matching Guidelines (54 FR 25818 (June 19, 1989)), as well as this subpart, it shall be forwarded to the Defense Data Integrity Board (DIB) for approval or disapproval. (1) If the CMA is approved by the DIB, the DPO shall prepare and forward a report to both Houses of Congress and to OMB as required by, and consistent with, OMB Circular A-130, "Management of Federal Information Resources," February 8, 1996, as amended. Congress and OMB shall have 40 days to review and comment on the proposed match. Any comments

received must be resolved before matching can take place. (2) If the CMA is approved by the DIB, the DPO shall prepare and forward a match notice as required by OMB Circular A-130, "Management of Federal Information Resources," February 8, 1996, as amended, for publication in the Federal Register. The public shall be given 30 days to comment on the proposed match. Any comments received must be resolved before matching can take place. § 310.53 Computer matching agreements (CMAs). (a) If a match is to be conducted internally within DoD, a memorandum of understanding (MOU) shall be prepared. It shall contain the same elements as a CMA, except as otherwise indicated in paragraph (b)(4)(ii) of this section. (b) A CMA shall contain the following elements: (1) Purpose. Why the match is being proposed and what will be achieved by conducting the match. (2) Legal authority. What is the Federal or state statutory or regulatory basis for conducting the match. The Privacy Act does not constitute independent authority for matching. Other legal authority shall be identified. (3) Justification and expected results. Explain why computer matching as opposed to some other administrative means is being proposed and what the expected results will be, including a specific estimate of any savings (see paragraph (b)(13) of this section). (4) Records description. Identify: (i) The system of records or non-Federal records. For DoD systems of records, provide the Federal Register citation for the system notice; (ii) The specific routine use in the system notice if records are to be disclosed outside the Department of Defense (see § 310.22(c)). If records are disclosed within the Department of Defense for an internal match, disclosures are permitted pursuant to paragraph (a) of § 310.22. (iii) The number of records involved; (iv) The data elements to be included in the match; (v) The projected start and completion dates of the match. CMAs remain in effect for 18 months but can be renewed for an additional 12 months provided: (A) The match will be conducted without any change, and (B) Each party to the match certifies in writing that the program has been conducted in compliance with the CMA or MOU. (vi) How frequently will the records be matched. (5)

(Response) FDA understands the comments' concerns about protecting the confidentiality of nonpublic information. If a person wishes to create separate records that do not contain certain confidential information, the person may do so, as long as the records are created at the time the food is received or released and the records contain the information required by the regulations. In addition, section 306 of the Bioterrorism Act excludes many types of confidential data from the record requirements: Recipes for food (see § 1.328 for the definition of recipe), (printed page 71608) financial data, pricing data, personnel data, research data, and sales data (other than shipment data regarding sales). Section 306 of the Bioterrorism Act, however, does not allow other types of confidential data to be withheld from FDA even if they are confidential. The laws governing FDA's activities, however, require it to protect certain trade secret and confidential information. See responses to comments 74 and 154 of this document. Further, because timely information is critical to a tracing investigation, records and other information must be made available to FDA as soon as possible, not to exceed 24 hours from the time of a request (§ 1.361 of this final rule). If the provision of information and records to FDA is delayed so that information can be redacted, the information and records may not have been provided as soon as possible. (Comment 154) Comments ask that FDA take steps to maintain the confidentiality of the information it receives. One comment asks that FDA develop and inform the public of procedural safeguards it will follow to obtain the information needed without jeopardizing the confidentiality of business information. Two comments ask that FDA provide guidance about its information disclosure procedures. Other comments ask how FDA will ensure the confidentiality of sensitive business information. Comments ask that FDA provide for special procedures to safeguard the confidentiality of the identities of flavors and spices and other secret ingredients in a recipe. Two comments request that FDA issue a regulation and another comment suggests that FDA issue an interim final regulation concerning the statutory requirement under section 414(c) of the FD&C Act to prevent unauthorized disclosure of any trade secret or confidential information. A comment asks that FDA provide a paragraph in a regulation requiring that FDA maintain the confidentiality of nonpublic information. That comment expresses concern about information FDA might receive from an "unaffected source," "incorrectly implicated sources" in the distribution chain, or the identity of a food company that was the victim of "food contamination in premeditated form." A comment asks that FDA amend its public information regulations to provide that information obtained under the records access authority is exempt from disclosure under FOIA.

(1) Make available to the individual to whom the record pertains all disclosure accountings except when: (i) The disclosure has been made to a law enforcement activity under paragraph (g) of § 310.22 and the law enforcement activity has requested that disclosure not be made; or (ii) The

system of records has been exempted from the requirement to furnish the disclosure accounting under the provisions of § 310.26(b). (2) If disclosure accountings are not maintained with the record and the individual requests access to the accounting, prepare a listing of all disclosures (see paragraph (b) of this section) and provide this to the individual upon request. Subpart F-Exemptions § 310.26 Use and establishment of exemptions. (a) Types of exemptions. (1) There are three types of exemptions permitted by the Privacy Act (5 U.S.C. 552a). (i) An access exemption that exempts records compiled in reasonable anticipation of a civil action or proceeding from the access provisions of the Act. (ii) General exemptions that authorize the exemption of a system of records from all but certain specifically identified provisions of the Act (see Appendix D). (iii) Specific exemptions that allow a system of records to be exempted only from certain designated provisions of the Act (see Appendix D). (2) Nothing in the Act permits exemption of any system of records from all provisions of the Act. (b) Establishing exemptions. (1) The access exemption is self-executing. It does not require an implementing rule to be effective. (2) Neither a general nor a specific exemption is established automatically for any system of records. The Heads of the DoD Components maintaining the system of records must make a determination whether the system is one for which an exemption properly may be claimed and then propose and establish an exemption rule for the system. No system of records within the Department of Defense shall be considered exempted until the Head of the Component has approved the exemption and an exemption rule has been published as a final rule in the Federal Register (See § 310.30(e).) (3) Only the Head of the DoD Component or an authorized designee may claim an exemption for a system of records. (4) A system of records is considered exempt only from those provision of the Privacy Act (5 U.S.C. 552a) that are identified specifically in the Component exemption rule for the system and that are authorized by the Privacy Act. (5) To establish an exemption rule, see § 310.31. (c) Blanket exemption for classified material. (1) Component rules shall include a blanket exemption under 5 U.S.C. 552a(k)(1) of the Privacy Act from the access provisions (5 U.S.C. 552a(d)) and the notification of access procedures (5 U.S.C. 522a(e)(4)(H)) of the Act for all classified material in any systems of records maintained.

The Department identified ten categories of quantifiable costs arising from these proposals that would apply to all regulated entities: (1) conducting a Security Rule compliance audit; (2) obtaining written verification from their business associates or subcontractors that the business associates or subcontractors, respectively, have conducted the required verification of compliance with technical safeguards; (3) notifying other regulated entities when workforce members' access to ePHI is terminated; (4) completing network segmentation; (5) disabling ports and removing extraneous software; (6) deploying MFA; (7) deploying penetration testing; (8) updating policies and procedures; (9) updating workforce training programs; and (10) revising business associate agreements. Additionally, group health plans would be required to update plan documents to require health plan sponsors' compliance with the administrative, physical, and technical safeguards according to the Security Rule and notification of group health plans when health plan sponsors activate their contingency plan. Business associates would have additional obligations to verify compliance with technical safeguards and provide it in writing to covered entities (and subcontractors to business associates) and to notify covered entities upon activation of their contingency plans. Finally, although plan sponsors are not directly subject to the HIPAA Rules, by virtue of the plan document requirements, the Department estimates that certain group health plan sponsors (e.g., employers that provide group health benefits) would likely incur some quantifiable costs to improve safeguards for their electronic information systems that affect the confidentiality, integrity, or availability of ePHI and to notify group health plans upon activation of plan sponsors' contingency plan. The Department estimates that the first-year costs attributable to this proposed rule total approximately \$9 billion. These costs are associated with regulated entities and health plan sponsors engaging in the regulatory actions described above. For years two through five, estimated annual costs of approximately \$6 billion are attributable to costs of recurring compliance activities. Table 1 reports the present value and annualized estimates of the costs of this proposed rule covering a 5-year time horizon. Using a 2 percent discount rate, the Department estimates that this proposed rule would result in annualized costs of \$6.8 billion for regulated entities and health plan sponsors combined. Table 1-Accounting Table, Costs of the Proposed Rule, \$ Billions

Costs	Primary estimate	Year	dollars	Discount rate	Period
covered	Present Value	\$34	2023	Undiscounted	2026-2030
	Present Value	32	2023	2%	2026-2030
	Annualized	7	2023	2%	2026-2030

a Figures are rounded.

After an initial incident report, the Government and the DIB participant may voluntarily share

additional information that is determined to be relevant to a reported incident, including information regarding forensic analyses, mitigation and remediation, and cyber intrusion damage assessments. (d) Cyber intrusion damage assessment. Following analysis of a cyber incident, DC3/DCISE may provide information relevant to the potential or known compromise of DoD acquisition program information to the Office of the Secretary of Defense's Damage Assessment Management Office (OSD DAMO) for a cyber intrusion damage assessment. The Government may provide DIB participants with information regarding the damage assessment. (e) DIB participant attribution information. The Government acknowledges that information shared by the DIB participants under this program may include extremely sensitive proprietary, commercial, or operational information that is not customarily shared outside of the company, and that the unauthorized use or disclosure of such information could cause substantial competitive harm to the DIB participant that reported that information. The Government shall take reasonable steps to protect against the unauthorized use or release of such information (e.g., attribution information and other nonpublic information) received from a DIB participant or derived from such information provided by a DIB participant, including applicable procedures pursuant to paragraph (h) of this section. The Government will restrict its internal use and disclosure of attribution information to only Government personnel and Government support contractors that are bound by appropriate confidentiality obligations and restrictions relating to the handling of this sensitive information and are engaged in lawfully authorized activities. (f) Non-attribution information. The Government may share non-attribution information that was provided by a DIB participant (or derived from information provided by a DIB participant) with other DIB participants in the DIB CS/IA program, and may share such information throughout the Government (including with Government support contractors that are bound by appropriate confidentiality obligations) for cyber security and information assurance purposes for the protection of Government information or information systems. (g) Electronic media. Electronic media/files provided by DIB participants to DC3 under paragraphs (b), (c) and (d) of this section are maintained by the digital and multimedia forensics laboratory at DC3, which implements specialized handling procedures to maintain its accreditation as a digital and multimedia forensics laboratory. DC3 will maintain, control, and dispose of all electronic media/files provided by DIB participants to DC3 in accordance with established DoD policies and procedures. (h) Freedom of Information Act (FOIA).

· System Owner · Common Control Provider · Information Owner or Steward · System Security Officer
 · System Privacy Officer · Senior Agency Information Security Officer · Senior Agency Official
 for Privacy · Chief Acquisition Officer · Control Assessor NIST SP 800-37, REVISION 2 RISK
 MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for
 Security and Privacy

APPENDIX E PAGE 136 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-37r2> TABLE E-6: AUTHORIZATION TASKS, RESPONSIBILITIES, AND
 SUPPORTING ROLES RMF TASKS PRIMARY RESPONSIBILITY SUPPORTING ROLES TASK R-1 Authorization Package
 Assemble the authorization package and submit the package to the authorizing official for an
 authorization decision. · System Owner · Common Control Provider · System Security Officer ·
 System Privacy Officer · Senior Agency Information Security Officer · Senior Agency Official for
 Privacy · Control Assessor TASK R-2 Risk Analysis and Determination Analyze and determine the
 risk from the operation or use of the system or the provision of common controls. · Authorizing
 Official or Authorizing Official Designated Representative · Senior Accountable Official for Risk
 Management or Risk Executive (Function) · Senior Agency Information Security Officer · Senior
 Agency Official for Privacy TASK R-3 Risk Response Identify and implement a preferred course of
 action in response to the risk determined. · Authorizing Official or Authorizing Official
 Designated Representative · Senior Accountable Official for Risk Management or Risk Executive
 (Function) · Senior Agency Information Security Officer · Senior Agency Official for Privacy ·
 System Owner or Common Control Provider · Information Owner or Steward · Systems Security
 Engineer · Privacy Engineer · System Security Officer · System Privacy Officer TASK R-4
 Authorization Decision Determine if the risk from the operation or use of the information system
 or the provision or use of common controls is acceptable. · Authorizing Official · Senior
 Accountable Official for Risk Management or Risk Executive (Function) · Chief Information Officer
 · Senior Agency Information Security Officer · Senior Agency Official for Privacy · Authorizing
 Official Designated Representative TASK R-5 Authorization Reporting Report the authorization
 decision and any deficiencies in controls that represent significant security or privacy risk. ·
 Authorizing Official or Authorizing Official Designated Representative · System Owner or Common

Control Provider · Information Owner or Steward · System Security Officer · System Privacy Officer · Senior Agency Information Security Officer · Senior Agency Official for Privacy

3.5.6 | Attribute Review ... 3.5.6 Attribute Review Assigning one or more attributes to a subject indirectly grants the subject capabilities to perform various operations on system objects.

DFARS 252.204-7020 (NIST SP 800-171 DoD Assessment Requirements) Requires contractors to have current NIST SP 800-171 DoD Assessment for Medium and High assessment levels. DFARS 252.204-7020 works in conjunction with the CMMC program. While 252.204-7020 establishes the contractual requirement, CMMC (under 32 CFR Part 170) provides the assessment framework. Phase 1 began November 10, 2025, with Phase 2 (C3PAO certification requirements) scheduled for November 10, 2026.

These transition provisions would apply only to the requirement to amend contracts or other arrangements with business associates, and they would not affect any other compliance obligations under the Security Rule. For example, beginning on the compliance date of the final rule, assuming a final rule is published and that it is finalized as proposed, a business associate would be required to implement and document its implementation of the administrative, physical, and technical safeguards required by a revised Security Rule, except with respect to 45 CFR 164.308(b) and 164.314(a), even if the business associate's contract with the covered entity [876] has not yet been amended. Given the possibility of a similar burden on group health plans and plan sponsors to update plan documents by the compliance date, the Department is considering, but not proposing, a similar transition provision for plan documents. We are not proposing such provisions at this time because, unlike business associates, plan sponsors do not have independent obligations under the Security Rule. Instead, the obligations of plan sponsors are based entirely on the content of the plan documents. Accordingly, if the plan documents are not updated, plan sponsors are not obligated to comply with the requirements of the Security Rule because they are not regulated entities. In particular, the Department is considering, but not proposing at this time, adding a new paragraph (d) introductory text under 45 CFR 164.318, with the heading "Standard: Effect of prior plan documents for group health plans," stating that notwithstanding any other provisions of the subpart, a group health plan may allow a plan sponsor to create, receive, maintain, or transmit electronic protected health information pursuant to a written plan document with such group health plan that does not comply with § 164.314(b), only in accordance with paragraph (d)(1). The Department is also considering adding a new paragraph (d)(1) under 45 CFR 164.318, with the heading "Implementation specification: Plan documents for group health plans," stating that the requirements of paragraph (b) apply to the plan document between a group health plan and a plan sponsor in the same manner as such requirements apply to written contracts or other arrangements between a covered entity and a business associate. Similarly, the Department is considering, but not proposing at this time, adding a new paragraph (d)(2) under 45 CFR 164.318, with the heading "Group health plan responsibilities," stating that nothing in the section shall alter the requirements of a group health plan or plan sponsor to comply with the applicable provisions of the part other than § 164.314(b).

3. Request for Comment The Department requests comment on the foregoing proposals, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular:

According to Cryptographic Key Management Workshop Summary -- June 8-9, 2009, 2.1.4 The Future of IT Security and Privacy, Dr. George O. Strawn, NSF: 2.1.4 The Future of IT Security and Privacy, Dr. George O. Strawn, NSF Keynote Speaker: Dr. George Strawn is the National Science Foundation's Chief Information Officer (CIO), where he guides the agency in the development and design of innovative information technology. Since joining the NSF in 1991, Dr. Strawn has served as the Executive Officer of Computer and Information Science and Engineering (CISE) and as the Director of the CISE Division of Advanced Networking Infrastructure and Research. He was the Program Director of the NSFNET, which became the first national DS-3 Internet backbone network. - In computer technology we keep moving faster and faster. We have seen an improvement of price-performance in computer technology by a factor of nearly one million in the past 30 years. - Many NSF Internet applications need security, including email, project funds management, travel, proposal submission and proposal evaluation. - If true security is required on today's Internet, a user must follow one of three laws: Don't buy a computer, Don't turn it on, or Don't attach it to a network. - NSF needs better integrated cryptography in its sensitive applications. Currently, NSF doesn't use PKI because of cost and complexity, but does use identity management, including identifying users and visitors, additional authentication of NSF users, and authorization of NSF users to systems and data. - NSF

security policy has been continually modified in accordance with new problems: we encrypt in https, we seldom do anything that requires un-proven methodologies for the first time, we follow all government rules, and we want to be told that something new is mandatory in order to justify a new budget item. - NSF now combines information management with security management. It has a strict security awareness program. Its visitor network was separated from its internal NSF user network, and all social security numbers in the system are encrypted.

Written comments and recommendations on the information collection should be sent to Ms. Jasmeet Seehra at the Office of Management and Budget, DoD Desk Officer, Room 10102, New Executive Office Building, Washington, DC 20503, with a copy to the Director, DIB CS/IA Program Office, at the Office of the DoD Chief Information Officer, 6000 Defense Pentagon, Attn: DIB CS/IA Program Office, Washington, DC 20301, or email at DIB.CS/IA.Reg@osd.mil . Comments can be received from 30 to 60 days after the date of this notice, but comments to OMB will be most useful if received by OMB within 30 days after the date of this notice. You may also submit comments, identified by docket number and title, by the following method: Federal Rulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. Instructions: All submissions received must include the agency name, docket number and title for this Federal Register document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing on the Internet at <http://www.regulations.gov> as they are received without change, including any personal identifiers or contact information. To request more information on this information collection or to obtain a copy of the proposal and associated collection instruments, please write to Director, DIB CS/IA Program Office, at Office of the DoD Chief Information Officer, Attn: DIB CS/IA Program Office, 6000 Defense Pentagon, Washington, DC 20301. Executive Order 13132 , ·Federalism· It has been certified that 32 CFR part 236 does not have federalism implications, as set forth in Executive Order 13132 . This rule does not have substantial direct effects on: (a) The States; (b) The relationship between the National Government and the States; or (c) The distribution of power and responsibilities among the various levels of Government. List of Subjects in 32 CFR Part 236 Contracts Security measures Accordingly 32 CFR part 236 is added to read as follows: PART 236·DEPARTMENT OF DEFENSE (DOD)-DEFENSE INDUSTRIAL BASE (DIB) VOLUNTARY CYBER SECURITY AND INFORMATION ASSURANCE (CS/IA) ACTIVITIES 236.1 Purpose. 236.2 Definitions. 236.3 Policy. 236.4 Procedures. 236.5 Cyber security information sharing. 236.6 General provisions. 236.7 DIB participant eligibility requirements. Authority: 10 U.S.C. 2224 ; 44 U.S.C. 3506 ; 44 U.S.C. 3544 . §·236.1 Purpose. Cyber threats to DIB unclassified information systems represent an unacceptable risk of compromise of DoD information and pose an imminent threat to U.S. national security and economic security interests. DoD's voluntary DIB CS/IA program enhances and supplements DIB participants' capabilities to safeguard DoD information that resides on, or transits, DIB unclassified information systems. §·236.2 Definitions. As used in this part: (a) Attribution information

means a person who has a favorable determination of eligibility for access to classified information, has signed an approved nondisclosure agreement, and has a need-to-know. Branch office means an office of an entity which is located somewhere other than the entity's main office location. A branch office is simply another location of the same legal business entity, and is still involved in the business activities of the entity. CCIPP means security sharing of classified information under a designated critical infrastructure protection program with such authorized individuals and organizations as determined by the Secretary of Homeland Security. CDC means a subset of contractors cleared under the NISP who have classified contracts with the DoD. Certification means comprehensive evaluation of an information system component that establishes the extent to which a particular design and implementation meets a set of specified security requirements. Classification guide means a document issued by an authorized original classifier that identifies the elements of information regarding a specific subject that must be classified and prescribes the level and duration of classification and appropriate declassification instructions. Classified contract means any contract, license, agreement, or grant requiring access to classified information by a contractor and its (printed page 83314) employees for performance. A contract is referred to in this rule as a ·classified contract· even when the contract document and the contract provisions are not classified. The requirements prescribed for a ·classified contract· also are applicable to all phases of precontract, license or grant activity, including solicitations (bids, quotations, and proposals), precontract negotiations, post-contract activity, or other government contracting activity (GCA) programs or projects which require access to classified information by a contractor. Classified covered information system means an information system

that is owned or operated by or for a cleared defense contractor and that processes, stores, or transmits information created by or for the DoD with respect to which such contractor is required to apply enhanced protection (e.g., classified information). A classified covered information system is a type of covered network consistent with the requirements of Section 941 of Public Law 112-239 and 10 U.S.C. 391 . Classified information means information that has been determined, pursuant to E.O. 13526 , or any predecessor or successor order, and the AEA of 1954, as amended, to require protection against unauthorized disclosure in the interest of national security and which has been so designated. The term includes NSI, RD, and FRD. Classified meetings means a conference, seminar, symposium, exhibit, convention, training course, or other such gathering during which classified information is disclosed. Classified visit

All affirmations shall be completed in SPRS. The Department will verify submission of the affirmation in SPRS to ensure compliance with CMMC solicitation or contract requirements. (1) CMMC Level 1 Self-Assessment. At the completion of a self-assessment and annually thereafter, the affirming official shall submit a CMMC affirmation attesting to continuing compliance with all CMMC Level 1 security requirements. (2) CMMC Level 2 Self-Assessment. At the completion of a self-assessment and annually thereafter, the affirming official shall submit a CMMC affirmation attesting to continuing compliance with all CMMC Level 2 security requirements. An affirmation shall also be submitted at the completion of a POA&M Closeout assessment. (3) CMMC Level 2 Certification Assessment. At the completion of a C3PAO assessment and annually thereafter, the affirming official shall submit a CMMC affirmation attesting to continuing compliance with all CMMC Level 2 security requirements. An affirmation shall also be submitted at the completion of a POA&M Closeout assessment. (4) CMMC Level 3 Certification Assessment. At the completion of a DCMA DIBCAC assessment and annually thereafter, the affirming official shall submit a CMMC affirmation attesting to continuing compliance with all CMMC Level 3 security requirements. This requirement is in addition to the ongoing requirement for Level 2 affirmation. An affirmation shall also be submitted at the completion of a POA&M Closeout assessment. §-170.23 Application to subcontractors. (a) Procedures. CMMC Level requirements apply to prime contractors and subcontractors throughout the supply chain at all tiers that will process, store, or transmit FCI or CUI on contractor information systems in the performance of the contract or subcontract. Prime contractors shall comply and shall require subcontractor compliance throughout the supply chain at all tiers with the applicable CMMC level for each subcontract as follows: (1) If a subcontractor will only process, store, or transmit FCI (and not CUI) in performance of the contract, then CMMC Level 1 Self-Assessment is required for the subcontractor. (2) If a subcontractor will process, store, or transmit CUI in performance of the subcontract, CMMC Level 2 Self-Assessment is the minimum requirement for the subcontractor. (3) If a subcontractor will process, store, or transmit CUI in performance of the subcontract and the Prime contractor has a requirement of Level 2 Certification Assessment, then CMMC Level 2 Certification Assessment is the minimum requirement for the subcontractor. (4) If a subcontractor will process, store, or transmit CUI in performance of the subcontract and the Prime contractor has a requirement of Level 3 Certification Assessment, then CMMC Level 2 Certification Assessment is the minimum requirement for the subcontractor. (b) [Reserved]. §-170.24 CMMC Scoring Methodology. (a) General.

NIST Special Publication 800-37 Revision 2 Risk Management Framework for Information Systems and Organizations A System Life Cycle Approach for Security and Privacy JOINT TASK FORCE This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-37r2> This publication contains comprehensive updates to the Risk Management Framework . The updates include an alignment with the constructs in the NIST Cybersecurity Framework; the integration of privacy risk management processes; an alignment with system life cycle security engineering processes; and the incorporation of supply chain risk management processes. Organizations can use the frameworks and processes in a complementary manner within the RMF to effectively manage security and privacy risks to organizational operations and assets, individuals, other organizations, and the Nation. Revision 2 includes a set of organization-wide RMF tasks that are designed to prepare information system owners to conduct system-level risk management activities. The intent is to increase the effectiveness, efficiency, and cost-effectiveness of the RMF by establishing a closer connection to the organization's missions and business functions and improving the communications among senior leaders, managers, and operational personnel.

3.2.2 Internet-based Attacks Though all networked or distributed applications are vulnerable to

internet-based attacks, microservices-based applications are more vulnerable to this type of attacks due to the following: - Unlike a monolithic application that exposes a smaller set of IP-addressable remote procedure call interfaces, a microservices architecture will almost always expose a larger set of IP-addressable remote procedure call interfaces.

3.1.22 Weaknesses that Affect Files and Directories CWE-632) Description Weaknesses in this category affect file or directory resources [§6.

(2) A privacy interest may exist in personal information even though the information has been disclosed at some place and time. This is known as the concept of practical obscurity. For example, information that was once publicly known (a court-martial trial 40 years ago) may no longer be in the public's eye and has faded from memory. In this case, the privacy interest in this type of situation may have increased over time, the public interest may have decreased over time, and therefore an agency can now withhold the once public information. (3) Examples of other files containing personal information similar to that contained in personnel and medical files include: (i) Those files compiled to evaluate or adjudicate the suitability of candidates for civilian employment or membership in the Armed Forces, and the eligibility of individuals (civilian, military, or contractor employees) for security clearances or for access to particularly sensitive classified information. (ii) Files containing reports, records, and other material pertaining to personnel matters in which administrative action, including disciplinary action may be taken. (4) On November 9, 2001, subsequent to the President declaring a national emergency, the DA&M issued a memorandum authorizing the DoD Components to withhold lists of personally identifying information of DoD personnel, to include active duty military personnel, civilian employees, contractors, members of the National Guard and Reserves, and military dependents. Additionally, personally identifying information of DoD military and civilian personnel who are assigned to overseas, sensitive, or routinely deployable, units is exempt from release under Exemption 3, with section 130b of 10 U.S.C. as the withholding statute. Names and duty addresses (postal and/or e-mail) published in telephone directories, organizational charts, rosters, and similar materials for personnel are considered -lists of personally identifying information;- and therefore qualify for withholding under Exemption 6 (and Exemption 3 if applicable). (5) Home addresses, telephone numbers, and private e-mail addresses are normally protected by this exemption. This includes lists of home addressees and military quarters' addressees that do not include the occupants' names. (6) This exemption shall not be used in an attempt to protect the privacy of a deceased person. It may be used to protect the privacy of the deceased person's surviving family members if disclosure would rekindle grief, anguish, pain, embarrassment, or even disruption of peace of mind of surviving family members. In such situations, the DoD Components shall balance the surviving family members' privacy interests and the public's interest to determine its releasability.

The reduced benefits from extending the compliance period by 6 months for each person subject to the final rule are a twofold increase in the number of outbreak victims relative to the baseline in the first year only. Baseline benefits reduce the impact of 15 percent to 18 percent of outbreaks and eliminate the problem of prematurely terminated investigations because of poor records quality (i.e., about 10 percent of the total number of traceback investigations estimated from FDA outbreak investigation information). Extending the compliance dates by 6 months ranks sixth in the reductions in benefits relative to the baseline. We estimate that allowing transporters to comply with this final rule by complying with existing requirements (e.g., records already required by FMCSA) will have a negligible impact on the benefits relative to that from the more comprehensive requirements of the proposal. Option 7 in table 16 of this document incorporates a 24-hour access provision, 6, 12, and 24 month retention requirements, extension of the compliance dates, and adjusted recordkeeping requirements for transporters based on existing requirements. In table 18 of this document, the costs and benefits of the final rule are compared with those from the adjusted comprehensive coverage of option 7 in table 16 of this document. Table 16. Costs and Reductions in Food Safety Benefits for Changes Based on Comments Policy Option (in Terms of the Baseline) Cost (7% Discount) Cost (3% Discount) Reduction in Benefits Relative to the Baseline Baseline 1 : Proposed rule except requirement for all records to contain lot codes is relaxed. \$4.0 billion \$5.27 billion (printed page 71643) (1) Baseline except existing interstate transporter requirements are sufficient. \$3.78 billion \$4.97 billion No reduction 2 1 (2) Baseline except retention of 6, 12, and 24 months per NIST standards \$4.0 billion \$5.27 billion Negligible reduction 2 (3) Baseline except food contact entities are excluded. 3 \$3.92 billion \$5.16 billion Exclude 37,000 facilities near the top of supply chain. Low risk of contamination and low

risk of loss of the paper trail. 3 (4) Baseline except compliance dates are extended by 6 months. \$3.73 billion \$5.10 billion An estimated one-time, two-fold increase in the number of victims compared with the baseline in the first year only. 4 (5) Baseline except foreign facilities are excluded. \$3.23 billion \$4.26 billion Exclude 225,000 facilities near the beginning of the supply chain. Very high cost of enforcement and access. 5 (6) Baseline except relax records access from 4 and 8 hours, to 24 hours. \$3.74 billion \$4.95 billion Adds a maximum of about 5 days to the time for preventive action during an outbreak. 6 (7) Adjusted comprehensive coverage \$2.59 billion \$3.57 billion Incorporates all policy options and adjusted numbers of facilities 1

(iii) If the request for access pertains to a record controlled and maintained by another Federal agency, but in the temporary custody of the NGB, the records are the property of the originating Component. Access to these records is controlled by the system notice and rules for the originating component/agency. Such requests shall be referred to the originating component/agency and the requestor will be notified in writing of the referral and contact information for the component/agency. (5) The Chief of the OIP will use the following procedures for processing any recommended denials of access: (i) The specific reason for denial cited by the System Manager will be evaluated and a recommendation will be presented to the denial authority. (ii) If the request for access is denied, a written letter will be sent to the requestor using procedures outlined in 32 CFR part 310, subpart D . The requestor will be advised they have 60 calendar days to appeal the decision to deny access. Appeals should be sent to: NGB Chief Counsel, 1636 Defense Pentagon, Room 1D164, Washington DC 20301-1636. The requester must provide proof of identity or a sworn declaration with their appeal, as outlined in 32 CFR part 310, subpart D . (iii) If the request for access should be granted, the access request will be directed back to the System Manager to process. (6) The Chief Counsel will use the following procedures for any appeals received: (i) The Chief Counsel will notify the Chief of the OIP that an appeal has been received and will request the administrative record of the initial denial. (ii) The Chief of the OIP will provide an exact copy of all records from the initial denial to the Chief Counsel within 10 working days. (iii) The Chief Counsel will review the appeal and make a final determination on whether to grant or deny the appeal. (A) If the appellate authority denies the appeal, he or she will provide a formal written notification to the requestor using the procedures outlined in 32 CFR part 310, subpart D and will provide a copy of the response to the Chief of the OIP. (B) If the appellate authority grants the appeal, he or she will notify the Chief of the OIP and the Directorate that recommended the denial that the individual is being given access to the record. The Chief Counsel will provide a subsequent notification to the requestor advising that his or her appeal has been granted, and will provide the requestor access to his or her record. (iv) All appeals should be processed within 30 working days after receipt by the Chief Counsel. If the Chief Counsel determines that a fair and equitable review cannot be made within that time, the individual shall be informed in writing of the reasons for the delay and of the approximate date the review is expected to be completed. (7) There is no requirement that an individual be given access to records that are not in a group of records that meet the definition of a SOR in 5 U.S.C. 552a .

Definitions have been added for: Affirming Official, Assessment objective, Asset, CMMC security requirement, CMMC Status, DoD Assessment Methodology, Enduring Exception, Operational plan of action, Personally Identifiable Information, Security Protection Data (SPD), and Temporary deficiency. Some definitions were also changed to source from NIST documentation instead of Committee on National Security Systems (CNSS) Instruction No. 4009. Background A. Statement of Need for This Rule The Department of Defense (DoD) requires defense contractors to protect FCI and CUI. To verify contractor and subcontractor implementation of DoD's cybersecurity information protection requirements, the Department developed the Cybersecurity Maturity Model Certification (CMMC) Program as a means of assessing and verifying (printed page 83169) adequate protection of contractor information systems that process, store, or transmit either FCI or CUI. The CMMC Program is intended to: (1) align cybersecurity requirements to the sensitivity of unclassified information to be protected, (2) add a self-assessment element to affirm implementation of applicable cybersecurity requirements, (3) add a certification element to verify implementation of cybersecurity requirements, and (4) add an affirmation to attest to continued compliance with assessed requirements. As part of the program, DoD also intends to provide supporting resources and training to the DIB, to help support companies who are working to achieve the required CMMC Status. The CMMC Program provides for assessment at three levels, starting with basic safeguarding of FCI at CMMC Level 1, moving to the broad protection of CUI at CMMC Level 2, and culminating with higher-level protection of CUI against risk from Advanced Persistent Threats (APTs) at CMMC Level 3. The

CMMC Program addresses DoD's need to protect FCI and CUI during the acquisition and sustainment of products and services from the DIB. This effort is instrumental in establishing cybersecurity as a foundation for DoD acquisitions. Although DoD contract requirements to provide adequate security for covered defense information (reflected in DFARS clause 252.204-7012) predate CMMC by many years, a verification requirement for the handling of CUI to assess a contractor or subcontractor's implementation of those required information security controls is new with the CMMC Program. The theft of intellectual property and sensitive information from all U.S. industrial sectors from malicious cyber activity threatens economic security and national security. The Council of Economic Advisers estimates that malicious cyber activity cost the U.S. economy between \$57 billion and \$109 billion in 2016. [24] The Center for Strategic and International Studies estimates that the total global cost of cybercrime was as high as \$600 billion in 2017. [25]

means a generic name for a computerized system that is capable of gathering and processing data and applying operational controls over long distances. Typical uses include power transmission and distribution and pipeline systems. SCADA was designed for the unique communication challenges (e.g., delays, data integrity) posed by the various media that must be used, such as phone lines, microwave, and satellite. Usually shared rather than dedicated, as defined in NIST SP 800-82r3 (incorporated by reference, see § 170.2). System Security Plan (SSP) means the formal document that provides an overview of the security requirements for an information system or an information security program and describes the security controls in place or planned for meeting those requirements. The system security plan describes the system components that are included within the system, the environment in which the system operates, how the security requirements are implemented, and the relationships with or connections to other systems, as defined in NIST SP 800-53 R5 (incorporated by reference, see § 170.2). Temporary deficiency means a condition where remediation of a discovered deficiency is feasible, and a known fix is available or is in process. (printed page 83220) The deficiency must be documented in an operational plan of action. A temporary deficiency is not based on an 'in progress' initial implementation of a CMMC security requirement but arises after implementation. A temporary deficiency may apply during the initial implementation of a security requirement if, during roll-out, specific issues with a very limited subset of equipment is discovered that must be separately addressed. There is no standard duration for which a temporary deficiency may be active. For example, FIPS-validated cryptography that requires a patch and the patched version is no longer the validated version may be a temporary deficiency. (CMMC-custom term) Test Equipment means hardware and/or associated IT components used in the testing of products, system components, and contract deliverables. (CMMC-custom term) User means an individual, or (system) process acting on behalf of an individual, authorized to access a system, as defined in NIST SP 800-53 R5 (incorporated by reference, see § 170.2). § 170.5 Policy.

, and the standards for the administrative safeguards under 45 CFR 164.308(a) . We also propose to clarify that regulated entities would be required to implement all of the administrative safeguards of the Security Rule to protect the confidentiality, integrity, or availability of all ePHI that they create, receive, maintain, or transmit. Thus, when read together, proposed 45 CFR 164.308(a) and 164.316(a) would require that a regulated entity implement and document, in writing, its implementation of the administrative safeguards required by the Security Rule. These requirements set the baseline for administrative safeguards. Nothing in this NPRM would prevent a regulated entity from implementing additional administrative safeguards, provided that those additional safeguards do not conflict with any requirements in the Security Rule. The proposed changes are discussed in greater detail below. c. Section 164.308(a)(1)(i)-Standard: Technology Asset Inventory We propose to modify 45 CFR 164.308(a)(1) by elevating to standard-level status the existing implementation specifications for the standard for security management process at 45 CFR 164.308(a)(1)(ii)(A) through (D) , and deleting the existing standard. Doing so would highlight the importance of these elements and permit us to add implementation specifications that detail our expectations for compliance with those elements. We believe that providing more specificity in our requirements would help regulated entities better understand their compliance responsibilities for (printed page 937) safeguarding ePHI. These proposals are consistent with current guidance, as described below. In place of the existing standard for security management process, we propose a standard at 45 CFR 164.308(a)(1)(i) that would require a regulated entity to conduct and maintain an accurate and thorough written technology asset inventory and a network map of its electronic information systems and all technology assets that may affect the confidentiality, integrity, or availability of ePHI. The inventory forms the foundation for a fulsome and accurate risk analysis. A regulated entity must identify its information systems that create, receive, maintain, or transmit

ePHI and all technology assets, as we propose to define them in 45 CFR 164.304, that may affect ePHI in such information systems in order to secure them. Regulated entities cannot understand the risks to the confidentiality, integrity, and availability of their ePHI without a complete understanding of these assets. We believe that this proposal would clarify compliance expectations and provide increased protections for the confidentiality, integrity, and availability of ePHI. Consistent with practices previously highlighted in guidance, regulated entities would be required by this proposal to conduct and maintain an accurate and thorough written inventory of technology assets.

For purposes of the RFA, small entities include small businesses, nonprofit organizations, and small governmental jurisdictions. The Act defines "small entities" as (1) a proprietary firm meeting the size standards of the SBA, (2) a nonprofit organization that is not dominant in its field, and (3) a small government jurisdiction of less than 50,000 population. The Department has determined that roughly 90 percent or more of all health care providers meet the SBA size standard for a small business as shown in table 4 or are a nonprofit organization. Therefore, the Department estimates that there would be 740,348 small entities affected by the proposals in this proposed rule. [999] The SBA size standard for health care providers ranges between a maximum of \$9 million and \$47 million in annual receipts, depending upon the type of entity, as shown in table 4, above. [1000] With respect to health insurers, the SBA size standard is a maximum of \$47 million in annual receipts, and for pharmacy benefits and clearinghouses it is \$45.5 million. [1001] While some insurers are classified as nonprofit, it is possible they are dominant in their market. For example, a number of Blue Cross/Blue Shield insurers are organized as nonprofit entities; and yet, they dominate the health insurance market in the States where they are licensed. [1002] With respect to business associates, they provide a wide range of services for covered entities, including computer infrastructure, clearinghouse activities, leased office equipment, and professional services, such as legal, accounting, business planning, and marketing. The SBA size thresholds for these industries ranges from \$15.5 million for lawyers to \$47 million for clearinghouses. [1003] For the reasons stated below, the Department does not expect that the cost of compliance would be significant for small entities. Nor does the Department expect that the cost of compliance would fall disproportionately on small entities. Although many of the regulated entities affected by the proposals in this proposed rule are small entities, they would not bear a disproportionate cost burden compared to the other entities subject to the rule. The projected total costs are discussed in detail in the RIA. The Department does not view this as a substantial burden because the result of the changes would be annualized costs per regulated entity of approximately \$1,235 [= \$2.3 billion [1004] /1,822,600 regulated entities]. The per-entity costs represent the costs per establishment. As a result, smaller entities' costs are lower because they have fewer establishments. Larger regulated entities (i.e., firms) that have multiple facilities (i.e.,

, Sections (c)(3) and (4); (d)(1) through (d)(5); (e)(1) through (e)(3); (e)(5); (f)(1) through (f)(5); (g)(1) through (g)(5); and (h) of the Act. (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons. The Defense Protective Service is the law enforcement body for the jurisdiction of the Pentagon and immediate environs. The nature of certain records created and maintained by the DPS requires exemption from access provisions of the Privacy Act of 1974. The general exemption, 5 U.S.C. 552a(j)(2) , is invoked to protect ongoing investigations and to protect from access, criminal investigation information contained in this record system, so as not to jeopardize any subsequent judicial or administrative process taken as a result of information contained in the file. (2) System identifier and name. JS006.CND, Department of Defense Counternarcotics C4I System. (i) Exemption. Portions of this system that fall within 5 U.S.C. 552a(j)(2) are exempt from the following provisions of 5 U.S.C. 552a , section (c)(3) and (4); (d)(1) through (d)(5); (e)(1) through (e)(3); (e)(4)(G) and (e)(4)(H); (e)(5); (f)(1) through (f)(5); (g)(1) through (g)(5) of the Act. (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons. (A) From subsection (c)(3) because the release of accounting of disclosure would inform a subject that he or she is under investigation. This information would provide considerable advantage to the subject in providing him or her with knowledge concerning the nature of the investigation and the coordinated investigative efforts and techniques employed by the cooperating agencies. (printed page 14803) This would greatly impede USSOUTHCOM's criminal law enforcement. (B) For subsections (c)(4) and (d) because notification would alert a subject to the fact that an investigation of that individual is taking place, and might weaken the on-going investigation, reveal investigatory techniques, and place confidential informants in jeopardy. (C) From subsections (e)(4)(G) and (H) because this system of records is exempt from the access provisions of subsection (d) pursuant to subsection (j). (D) From

subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going criminal investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to that individual, and record amendment procedures for this record system.

The intent of the rule is for use of the DD Form 254 for each specific contractual requirement requiring access to classified information. While the NISS website does not currently link to the DD Form 254 repository, Defense Counterintelligence and Security Agency will evaluate that capability during future assessment of requirements.

3. Support for the Rule Comment: Two respondents acknowledged that streamlining the DD Form 254 for electronic submission via the National Industrial Security Program (NISP) Contracts Classification System is beneficial as well as clarification of the SAM requirements. Response: The Government acknowledges the benefits with establishment of the rule to provide streamlined submission process procedures for use of the DD Form 254 through the PIIIE, to enable businesses to submit an electronic form once, instead of repeated paper submissions.

4. Paperwork Reduction Act Applicability Comment: One respondent conveyed concerns regarding the Paperwork Reduction Act burdens associated with the use of DD Form 254. Response: The Paperwork Reduction Act (44 U.S.C. chapter 35) applies; however, the proposed changes to the FAR do not impose additional information collection requirements to the paperwork burden previously approved under the Office of Management and Budget (OMB) Control Number 0704-0567, entitled "Department of Defense Contract Security Classification Specification".

5. Out of Scope Comment: One respondent commented on a variety of topics unrelated to the rule. Response: Comments are out of scope.

C. Other Changes There were minor administrative revisions to the format of the provision FAR 52.204-16, Commercial and Government Entity Code Reporting, and the clause FAR 52.204-18, Commercial and Government Entity Code Maintenance, including deleting use of the alternates at FAR 52.204-16(g) and FAR 52.204-18(f), incorporating the paragraphs at FAR 52.204-16(g) and FAR 52.204-18(f) into the base clause for clarity. Additionally, there were minor clarifying edits to the FAR text at FAR 4.402(d)(1) and (2), FAR 4.403(c)(1), and 52.204-16(b) and (g). As a result of conforming changes, revisions to FAR 4.1804 will no longer be required.

III. Applicability to Contracts at or Below the Simplified Acquisition Threshold (SAT) and for Commercial Items, Including Commercially Available Off-the-Shelf (COTS) Items This rule does not create any new provisions or clauses, nor does it change the applicability of any existing provisions or clauses included in solicitations and contracts valued at or below the SAT, or for commercial items, including COTS items.

IV. Executive Orders 12866 and 13563 E.O.s 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563

(Comment 175) A few comments point out that the burden for maintaining records is proportionately similar for large transporter companies and small independent transporters. Therefore, according to the comments, the relative regulatory burden for small, independent transporters is no greater than for large companies. The comments contend that all carriers, regardless of the size of the company, should be required to comply with the same requirements on the same timetable. (Response) As stated previously, the Bioterrorism Act specifically states that, in issuing these regulations, the Secretary shall take the size of a business into account. FDA believes it is appropriate to give small and very small businesses additional time to come into compliance with the regulations.

IV. Analysis of Economic Impacts-Final Regulatory Impact Analysis FDA has examined the economic implications of this final rule as required by Executive Order 12866 . Executive Order 12866 directs agencies to assess all costs and benefits of available regulatory alternatives and, when regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety, and other advantages; distributive impacts; and equity). Executive Order 12866 classifies a rule as significant if it meets any one of a number of specified conditions, including: Having an annual effect on the economy of \$100 million, adversely affecting a sector of the economy in a material way, adversely affecting competition, or adversely affecting jobs. A regulation is also considered a significant regulatory action if it raises novel legal or policy issues. FDA has determined that this final rule is an economically significant regulatory action as defined by Executive Order 12866 . This final regulatory impact analysis reflects changes made in the regulation from the proposed rule to the

final rule, as well as changes in estimates in response to comments. It also includes responses to comments on the preliminary regulatory impact analysis (PRIA) (see 68 FR 25188). Where there were no changes in the estimates provided in the PRIA, the estimates are summarized here. Interested persons are directed to the text of the PRIA for a fuller explanation of the estimates over which there were no significant comments or changes. As noted in the previous section of this preamble, FDA received 212 submissions in response to the proposed rule, which raised over 200 issues. We continue with the discussion of the comments and FDA's responses to those comments using the same presentation as in section III of this document, focusing here on the comments FDA received on the PRIA. Accordingly, the word 'Comment' again will appear in parenthesis before the description of the comment, and the word 'Response' will appear in parenthesis before FDA's response. A. Summary of the Costs and Benefits of the Final Rule

3.1.2 | Test Results... 3.1.2 Test Results Figure D-31 shows the remote connection being established through the Cisco AnyConnect VPN application through which a browser is used to access the ConsoleWorks web interface (Figure D-32). 3.1.24 - PI Interface for SNMP ReadOnly version 1.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Health and Human Services Food and Drug Administration [Docket No. FDA-2014-N-1697] AGENCY: Food and Drug Administration, HHS. ACTION: Notice of a Privacy Act system of records. SUMMARY: In accordance with the requirements of the Privacy Act of 1974 (the Privacy Act) and the Food and Drug Administration's (FDA or the Agency) regulations for the protection of privacy, FDA is publishing notice of a Privacy Act system of records entitled, 'FDA Commissioning of State and Local Officials, HHS/FDA/ORA' System No. 09-10-0022. FDA is deleting the System of Records Notice (SORN) for 'FDA Credential Holder File, HHS/FDA/OC' System No. 09-10-0003, because the records covered by that SORN are now covered by this new SORN and by existing personnel records SORNs. The new system of records will contain information about State and local officials who have applied for an FDA commission that would allow them to assist FDA with its regulatory compliance and enforcement efforts. FDA will use the records in this system to assess qualifications of commissioning candidates, initiate background investigations, record the status of applications, and track the status of commissioned officials. DATES: Effective Date: The new system of records will be effective on December 8, 2014 with the exception of the routine uses. The routine uses will be effective on January 22, 2015. Submit either electronic or written comments by January 22, 2015. ADDRESSES: You may submit comments by any of the following methods: Electronic Submissions Submit electronic comments in the following way: Federal eRulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. Written Submissions Submit written submissions in the following ways: Mail/Hand delivery/Courier (for paper submissions): Division of Dockets Management (HFA-305), Food and Drug Administration, 5630 Fishers Lane, Rm. 1061, Rockville, MD 20852. Instructions: All submissions received must include the Docket No. FDA-2014-N-1697 for this notice. All comments received may be posted without change to <http://www.regulations.gov> , including any personal information provided. For additional information on submitting comments, see the 'Comments' heading of the SUPPLEMENTARY INFORMATION section of this document. Docket: For access to the docket to read background documents or comments received, go to <http://www.regulations.gov>

: The Bioterrorism Act contains a provision authorizing the Secretary to establish requirements regarding the establishment and maintenance of records by persons who manufacture, process, pack, transport, distribute, receive, hold, or import food which are needed to allow the Secretary to identify the immediate previous sources and immediate subsequent recipients of food, including its packaging, in order to address credible threats of serious adverse health consequence or death to humans or animals. Description of Respondents : Persons that manufacture, process, pack, hold, receive, distribute, transport, or import food in the United States are required to establish and maintain records, including persons that engage in both interstate and intrastate commerce. FDA received several comments about the hourly burden imposed by the rule on respondents. (Comment 222) One comment states that the cumulative effect of the regulation is a staggering amount of required paperwork that needs to be organized and made available. (Response) This comment is not directly responding to any specific request for comments but is a general comment. The duplication of records

is unnecessary as long as existing records contain all of the required information. In this analysis we use the FDA small business model to calculate the effects on small businesses using the difference between revenues and variable costs as the metric. We incorporated both the one-time costs and the recurring costs to compute the effects on small businesses. The effects were computed for firms in the dietary supplements industry, candy manufacturing, and the ready-to-eat food manufacturing industry, including firms that manufacture breakfast cereals, beverages, canned foods, baked items and breads, and dressings and sauces. While these firms do not represent every category of food establishment covered by this final rule, they do reflect a large number of firms in the food industry, including manufacturers, input suppliers, and distributors. FDA assumes that the cost and revenue structures of firms not explicitly included in the computation of the model do not differ substantially from those that are included. Consistent with FDA's assumption that the rule will require only small changes to current recordkeeping practices, the findings from the small business model indicate that virtually no small businesses will incur negative cash flows as a result of this rule. The percentages of firms predicted to incur negative cash flows are range from 0.2 percent to a high of 1.9 percent for the ready-to-eat food manufacturing industry. These findings strongly suggest that very few firms, if any, will be driven from business as a result of this rule. In the Unfunded Mandates section of the PRIA, we also consider the impacts of the proposal on food prices and conclude that any effect would be negligible.

7. Executive Office of the President of the United States, Economic Report of the President (Feb. 2010), available at <http://www.whitehouse.gov/administration/eop/cea/economic-report-of-the-president> . Back to Citation 8. The Nation relies increasingly on the Internet not only as a platform for commercial activities, but also as a vehicle for innovation, national competitiveness, and a tool for efficiency, transparency and accountability in government. Back to Citation 9. U.S. Census Bureau, E-Stats, May 28, 2009, <http://www.census.gov/econ/estats/2007/2007reportfinal.pdf> , at 2. Back to Citation 10. Id. More recent data released in May 2010 show that this trend continued in 2008. U.S. Census Bureau, E-Stats, May 27, 2010, <http://www.census.gov/econ/estats/2008/2008reportfinal.pdf> . Back to Citation 11. U.S. Census Bureau, Quarterly Retail E-Commerce Sales: 4th Quarter 2008, Feb. 16, 2010. Back to Citation 12. U.S. M-Commerce Sales to Hit \$2.4 Billion This Year, ABI Research Says, Internet Retailer, Feb. 16, 2010, <http://www.internetretailer.com/2010/02/16/u-s-m-commerce-sales-to-hit-2-4-billion-this-year-abi-research> . Back to Citation 13. Id. Back to Citation 14. Cyberspace Policy Review at 2. Back to Citation 15. See, e.g., Tom Zeller, Jr., Cyberthieves Silently Copy Your Passwords as You Type, New York Times, Feb. 27, 2006, available at <http://www.nytimes.com/2006/02/27/technology/27hack.html> . Back to Citation 16. See Internet Crime Complaint Center, 2009 Internet Crime Report, http://www.ic3.gov/media/annualreport/2009_IC3Report.pdf . Back to Citation 17. National Cyber Security Alliance, Symantec, and Zogby International; 2009 NCSA/Symantec Small Business Study, Oct. 2009, <http://www.staysafeonline.org/files/2009SMBStudy/FullSMBStudy2009%20FINAL.pdf> , at 4. Back to Citation 18. National Initiative for Cybersecurity Education (NICE), Relationship to President's Education Agenda (April 19, 2010), http://www.whitehouse.gov/sites/default/files/rss_viewer/cybersecurity_niceeducation.pdf ; see also Commerce Secretary Gary Locke Announces NIST to Lead National Initiative for Cybersecurity Education, (April 29, 2010), <http://www.commerce.gov/news/press-releases/2010/04/29/commerce-secretary-gary-locke-announces-nist-lead-national-initiative> . Back to Citation 19. See, e.g., California Database Breach Act, California Civil Code §§.1798.80-1798.82 (enacted in 2002). Back to Citation

This section provides further guidance on what type of information is expected for a specific requirement or set of requirements from Annex B and the additional requirements listed in Section 3.2. All of the requirement statements are organized into appropriately named and numbered subsections (e.g., 1.2 - Security Levels, 2.1 - Purpose or Use). Each subsection identifies the applicable requirements and provides any clarifying and explanatory notes.

(Response) Although the comment states that 3 hours is too low an estimate, the comment did not indicate how the learning cost estimates as a whole, or any of the component cost estimates, can be improved. FDA explicitly incorporates the costs of searching, learning, and comprehending the rule in the PRIA. Learning cost estimates are composed of costs for searching for a copy of the requirements, and reading and understanding them. Because of the approximate nature of the calculation, FDA rounds up to the nearest half hour to 3 1/2 hours for the time required for reading

and comprehending the requirements of this final rule for all English reading users. Although the cost of viewing the explanatory video was not explicitly included in the PRIA, such a viewing was assumed to reduce the burden from other searching and learning activities. Consequently, in the analysis of the final rule, FDA maintains the learning costs estimates used in the PRIA. 9. Specific Sector Cost Estimates a. Transportation and warehouse sector . (Comment 205) At least one comment states that trucking companies already maintain the required records to comply with another Federal regulation and therefore additional Federal requirements would be duplicative. (Response) FDA has included several options in this final rule for transporters to comply with their obligations to establish and maintain records under this final rule. One option is for transporters to keep some of the records currently required by the FMCSA regulations as of the date of publication of this final rule. The FMCSA regulations already require interstate transporters to establish and maintain transportation records, and we assume that interstate transporters who already comply with the FMCSA recordkeeping requirements will choose to comply with this final rule by maintaining such records. However, the FMCSA regulations cover only interstate common carriers, while this regulation covers all persons who transport food, including intrastate carriers. Moreover, domestic air carriers, and interstate transporters of low-value packages may not be required to comply with FMCSA regulations. Consequently, as a result of this final rule, intrastate carriers, intrastate shipments by interstate carriers, domestic air cargo carriers, and transporters of low-value packages may incur recordkeeping costs, in addition to learning costs, as a result of this final rule. To estimate the costs incurred by intrastate carriers, domestic air cargo carriers, and transporters of low value (printed page 71638)

(b) Nine types of records may be withheld in whole or in part from public disclosure unless otherwise prescribed by law. In addition, a discretionary release of a record to one requester shall prevent the withholding of the same record under a FOIA exemption if the record is subsequently requested by someone else. However, a FOIA exemption may be invoked to withhold information that is similar or related that has been the subject of a discretionary release. (c) In applying exemptions, the identity of the requester and the purpose for which the record is sought are irrelevant, with the exception that an exemption may not be invoked where the particular interest to be protected is the requester's interest. (d) The DoD Components may have a situation where, in responding to a FOIA request, admitting the existence or nonexistence of a record would itself reveal information protected from release by one of the 9 Exemptions. In this situation, the DoD Component shall neither confirm nor deny the existence or nonexistence of the requested record. This is commonly called a ·Glomar· response (U.S. Attorney General Memorandum), and the appropriate exemption must be cited in the response. This situation most commonly arises with Exemptions 1, 6, and 7; however, it could arise with other exemptions. A ·refusal to confirm or deny· response must be used consistently, not only when a record exists, but also when a record does not exist. If not used consistently, the pattern of a ·no record· response when a record does not exist, and a ·refusal to confirm or deny· when a record does exist, will itself disclose exempt information. §.286.14 Applying the FOIA exemptions. The 9 types of exempted records and procedures for applying them are as follows: (a) Exemption 1. Pursuant to 5 U.S.C. 552(b)(1) , records properly and currently classified in the interest of national defense or foreign policy, as specifically authorized under the criteria established by an existing Executive Order establishing classification criteria and implemented by regulation, such as DoD 5200.1-R, (printed page 71854) are exempt from disclosure. If the responsive information is not classified at the time of the FOIA request, a classification review may be undertaken to determine whether the information should be classified. The procedures in DoD 5200.1-R apply in this situation. If the information qualifies as Exemption 1 information, there is no discretion regarding its release. The requester will be advised as to which sections of the Executive Order apply in determining the information classified. In addition, Exemption 1 shall be invoked when the following situations are apparent:

Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided to the President and others are not compromised, to protect records used solely as statistical records, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality

and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records may be exempt from specific provisions of 5 U.S.C. 552a . (4) System identifier and name. A0027-1 DAJA, General Legal Files. (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958 , as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (D) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6) , if the disclosure would compromise the objectivity or fairness of the test or examination process. (E) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7) , but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (F) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(1) through (k) (7) from subsections 5 U.S.C. 552a(c)(3)

(DFAS). Address requests to any DFAS regional office or to Headquarters, DFAS. For Headquarters, DFAS, records, or if there is uncertainty as to which DFAS region may have the records, address requests to: Defense Finance and Accounting Service, DFAS-HAC/DE, Corporate Communications, 6760 East Irvington Place, Denver, CO 80279-8000. Addresses for DFAS regional office FOIA Requester Service Centers are located at <http://www.dfas.mil> . AP2.2.9. Defense Information Systems Agency (DISA). DISA records may be requested from any DISA field activity or from its Headquarters. Requesters should send FOIA requests to Defense Information Systems Agency, Attn: Headquarters FOIA Requester Service Center, P.O. Box 4502, Arlington, VA 22204-4502. <http://www.disa.mil/gc/foia/foia.html> . AP2.2.10. Defense Intelligence Agency. Defense Intelligence Agency, Attn: DIAC, DAN-1A (FOIA), Washington, DC 20340-5100. <http://www.dia.mil/publicaffairs/Foia/foia.htm> . AP2.2.11. Defense Logistics Agency (DLA). DLA records may be requested from its headquarters or from any of its field activities. Requesters should send FOIA requests to Defense Logistics Agency, Attn: DP-FOIA, 8725 John J. Kingman Road, Suite 2533, Ft. Belvoir, VA 22060-6221. Addresses for DLA field activity FOIA Requester Service Centers are located at http://www.dla.mil/public_info/efoia/FOIAPOC.html . AP2.2.12. Defense Security Service. Defense Security Service, Office of FOIA and Privacy, 1340 Braddock Place, Alexandria, VA 22314-1651. <http://www.dss.mil/foia/foia.html> . AP2.2.13. Defense Threat Reduction Agency. Defense Threat Reduction Agency, COSMI FOI/Privacy Office, 8725 John J. Kingman Rd., Fort Belvoir, VA 22060-6201. <http://www.dtra.mil/be/FOIA/index.cfm> . AP2.2.14. National Geospatial-Intelligence Agency. National Geospatial-Intelligence Agency, Office of General Counsel, Attn: GCP, Mail Stop D-10, 4600 Sangamore Road, Bethesda, MD 20816-5003. <http://www.nga.mil> . AP2.2.15. National Reconnaissance Office. National Reconnaissance Office, Information Access and Release Center, Attn: FOIA Officer, 14675 Lee Road, Chantilly, VA (printed page 71868) 20151-1715. <http://www.nro.gov/foia/index.html> AP2.2.16. National Security Agency. National Security Agency/Central Security Service, FOIA/PA Services, DC34, 9800 Savage Road, Suite 6248, Fort George G. Meade, MD 20755-6248. <http://www.nsa.gov/foia/index.cfm> . AP2.2.17. Inspector General of the Department of Defense. Inspector General of the Department of Defense, Chief FOIA/PA Office, 400 Army Navy Drive, Room 201, Arlington, VA 22202-4704. <http://www.dodig.osd.mil/fo/foia/foia.htm> . AP2.3. DoD Field Activity And Combatant Command Addresses Although the below FOIA Requester Service Centers are OSD Components for the purposes of the FOIA, these Centers respond directly to the public on initial requests. Accordingly, initial requests should be sent to the addresses indicated. AP2.3.1. DoD TRICARE Management Activity.

, would require a regulated entity to create copies of ePHI in a manner that ensures that such copies are no more than 48 hours older than the ePHI maintained in the regulated entity's relevant electronic information systems and in accordance with the policies and procedures required by

proposed 45 CFR 164.308(a)(13)(ii)(B). The second, 45 CFR 164.312(i)(2)(ii), would require a regulated entity to deploy technical controls that, in real-time, monitor, and alert workforce members about, any failures and error conditions of the backups required by the first implementation specification. The third, 45 CFR 164.312(i)(2)(iii), would require a regulated entity to deploy technical controls that record the success, failure, and any error conditions of backups required. The fourth, 45 CFR 164.312(i)(2)(iv), would require a regulated entity to test the effectiveness of its backups and document the results at least monthly. Specifically, a regulated entity would be required to restore a representative sample of backed up ePHI (after the ePHI is backed up as required by paragraph (i)(2)(i)) and document the results of such test restorations at least monthly. Such tests should include verifying regulated entity's ability to access ePHI from a remote location. These activities are included in NIST guidance for Security Rule compliance, [816] which directs regulated entities to consider the following questions: Is the frequency of backups appropriate for the environment? Are backup logs reviewed and data restoration tests conducted to ensure the integrity of data backups? Is at least one copy of the data backup stored offline to protect against corruption due to ransomware or other similar attacks? The potential need for these requirements also has been indicated through the rising number of ransomware attacks and the high number of individuals affected in such incidents. The Department believes these new implementation specifications, if finalized, would provide additional instruction for regulated entities about conducting data backups and enhance the ability of regulated entities to avoid costly work stoppages and interruptions in the delivery of health care when data becomes unavailable because of a disaster, security incident, or other emergency. We believe enhanced measures for data backup would reduce the need to pay ransom to hackers to recover compromised data. k. Section 164.312(j)-Standard: Information Systems Backup and Recovery The Department also proposes to add a new standard for backup and recovery of relevant electronic information systems at proposed 45 CFR 164.312(j)

- Authority and Purpose (AP); - Accountability, Audit, and Risk Management (AR); - Data Quality and Integrity (DI); - Data Minimization and Retention (DM); - Individual Participation and Redress (IP); - Security (SE); - Transparency (TR); and, - Use Limitation (UL).

The following asset categories are part of the Level 2 CMMC Assessment Scope: · CUI Assets · Security Protection Assets · Contractor Risk Managed Assets · Specialized Assets Additional Guidance on Level 2 Scoping CMMC Assessment Scope · Level 2 | Version 2.13 9 Separation Techniques Separation is a system architecture design concept that can provide physical/logical isolation of assets that process, transmit, or store CUI from assets not involved with CUI. Effective separation involves logically or physically separating assets and is required only for Out-of-Scope Assets. By separating assets, the CMMC Assessment Scope can be limited. Effective separation for CMMC follows the guidance in NIST SP 800-171 Rev 2, which states: If nonfederal organization s designate specific system component s for the processing, storage, or transmission of CUI, the organization s may limit the scope of the security requirements by isolating the designated system component s in a separate CUI security domain. Isolation can be achieved by applying architectural and design concept s (e.g., implementing subnetworks with firewalls or other boundary protection devices and using information flow control mechanisms). Security domains may employ physical separation, logical separation, or a combination of both. This approach can provide adequate security for the CUI and avoid increasing the organization's security posture to a level beyond that which it requires for protecting its missions, operations, and assets. Logical separation occurs when data transfer between physically connected assets (wired or wireless) is prevented by non-physical means such as software or network assets (e.g., firewall, routers, VPNs, VLANs). Physical separation occurs when assets have no connection (wired or wireless). Data can only be transferred manually (e.g., USB drive). Self-assessments and certification assessments may be valid for a defined CMMC Assessment Scope as outlined in 32 CFR § 170.19 CMMC Scoping. A new assessment is required if there are significant architectural or boundary changes to the previous CMMC Assessment Scope. Examples include, but are not limited to, expansions of networks or mergers and acquisitions. Operational changes within a CMMC Assessment Scope, such as adding or subtracting resources within the existing assessment boundary that follow the existing SSP, do not require a new assessment, but rather may be covered by annual affirmations to the continuing compliance with requirements. External Service Provider Considerations An External Service Provider (ESP) can be within the OSA's scope of CMMC requirements if it meets CUI Asset and/or Security Protection Asset criteria. To be considered an ESP, data (specifically CUI or Security Protection Data, e.g., log data, configuration data) must reside on the ESP assets as set forth in

32 CFR § 170.19(c)(2). Special considerations for an OSA using an ESP include the following: · The use of an ESP, its relationship to the OSA, and the services provided need to be documented in the OSA's SSP and described in the ESP's service description and customer responsibility matrix (CRM), which describes the responsibilities of the OSA and ESP with respect to the services provided. · Evaluate the ESP's CRM where the provider identifies security requirement objectives that are the provider's responsibility and security requirement objectives that are the OSA's responsibility.

Others expressed concern that sharing certain artifacts during the assessment process or permitting assessors to retain them would create vulnerability. In addition, commenters asked whether security protections are required for documents held due to the artifact retention requirements. One commenter asked how CMMC assessment scores, or affirmation information will be protected, and whether the CMMC program office will share this information outside of DoD. Another suggested that C3PAOs should not be required to retain any OSC provided materials. One commenter misinterpreted the supplemental hashing guide as requiring use of the MS PowerShell script with the SHA256 algorithm. The commenter also stated it would be more efficient to specify a single hash be provided for combined artifacts rather than requiring separate hash values for each artifact. They recommended deletion of the hashing requirement. Another commenter suggested requiring OSCs to generate hashes for artifacts as part of a Level 2 self-assessment. One comment also asked whether hashing is required for Level 3 artifacts. One comment asked how long OSAs must retain artifacts following an assessment. Some comments expressed concern that C3PAOs that receive or retain OSA artifacts identified as CUI would be required to undergo assessment by both the DIBCAC and another C3PAO. Four commenters objected to the 6-year artifact retention requirement for C3PAOs and requested reduction to 1 year. Three commenters asked whether self-assessors at level 1 or level 2 must also retain supporting artifacts for 6 years. Two commenters recommended revised wording of CMMC Level 3 requirements to provide greater clarity about artifact retention and integrity. One commenter requested edits to the description of SSP content, advocating for deletion of references to organizational policies and procedures in place to comply with NIST SP 800-171 R2. The recommended edits also changed attribution of the requirement to create an SSP to reflect DFARS clause 252.204-7020 rather than DFARS clause 252.204-7012. This commenter also suggested additional wording to specify that the OSA need not define roles and responsibilities of security personnel in the SSP but may do so in ancillary documents. Response:

Data breaches caused by current and former workforce members are a recurring issue across many industries, including the health care industry. Effective identity and access management policies and controls are essential to reduce the risks posed by these types of insider threats. Identity and access management can include many processes, but, most commonly, it would include the processes by which appropriate access to data is granted and terminated by creating and managing user accounts. Ensuring that user accounts are terminated and in a timely manner so that former workforce members do not have access to data, is one important way identity and access management can help reduce risks posed by insider threats. Additionally, effective termination procedures also reduce the risk that inactive user accounts (e.g., user accounts that are not being used or are inactive but are not fully terminated or disabled) could be used by a current or former workforce member with malicious motives to get access to ePHI. The Department's guidance also offers tips to prevent unauthorized access to PHI by former workforce members, such as having standard procedures of all action items to be completed when an individual leaves. [557] Guidance that we issued in 2019 further explains that security is a dynamic process. [558] Good security practices entail continuous awareness, assessment, and action in the face of changing circumstances. The information users can and should be allowed to access may change over time; organizations should recognize this in their policies and procedures and in their implementation of those policies and procedures. For example, if a user is promoted, demoted, or transfers to a different department, a user's need to access data may change. In such situations, the user's data access privileges should be re-evaluated and, as needed, modified to match the new role, if needed. [559] As described in other HHS guidance, these procedures should also address the complexity of the organization and the sophistication of its relevant electronic information systems. [560] NIST guidance provides additional descriptions of key activities and sample questions for regulated entities to consider when implementing this standard and associated implementation specifications. [561] Regulated entities should establish a standard set of procedures that should be followed to recover access control devices (e.g., identification badges, keys, access cards) when employment ends and, likewise, they should timely deactivate computer access (e.g., disable user IDs and passwords) and facility access (e.g., change facility security codes/PINs). Sample questions for

implementation include the following: Are there separate procedures for voluntary termination (e.g., retirement, promotion, transfer, change of employment) versus involuntary termination (e.g.,

AC.L2-3.1.15 · Privileged Remote Access CMMC Assessment Guide · Level 2 | Version 2.13 47

AC.L2-3.1.15 · PRIVILEGED REMOTE ACCESS Authorize remote execution of privileged commands and remote access to security-relevant information. ASSESSMENT OBJECTIVES [NIST SP 800-171A]40

Determine if: [a] privileged commands authorized for remote execution are identified; [b] security-relevant information authorized to be accessed remotely is identified; [c] the execution of the identified privileged commands via remote access is authorized; and [d] access to the identified security-relevant information via remote access is authorized. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]40 Examine [SELECT FROM: Access control policy; procedures addressing remote access to the system; system configuration settings and associated documentation; system security plan; system audit logs and records; other relevant documents or records].

Interview [SELECT FROM: System or network administrators; personnel with information security responsibilities]. Test [SELECT FROM: Mechanisms implementing remote access management].

DISCUSSION [NIST SP 800-171 REV. 2]41 A privileged command is a human- initiated (interactively or via a process operating on behalf of the human) command executed on a system involving the control, monitoring, or administration of the system including security functions and associated security-relevant information. Security-relevant information is any information within the system that can potentially impact the operation of security functions or the provision of security services in a manner that could result in failure to enforce the system security policy or maintain isolation of code and data. Privileged commands give individuals the ability to execute sensitive, security-critical, or security-relevant system functions. Controlling such access from remote locations helps to ensure that unauthorized individuals are not able to execute such commands freely with the potential to do serious or catastrophic damage to 40 NIST SP 800-171A, p. 15. 41 NIST SP 800-171 Rev. 2, p. 14.

DFARS 252.204-7020 (NIST SP 800-171 DoD Assessment Requirements) Requires contractors to have current NIST SP 800-171 DoD Assessment for Medium and High assessment levels. Contractors should review the full text of DFARS 252.204-7020 in conjunction with their contracting officer and legal counsel to ensure full compliance. The clause should be read alongside the CMMC requirements at 32 CFR Part 170.

The Department of Defense published the proposed rule, on December 26, 2023 (88 FR 89058). Approximately 361 public submissions were received in response to the publication. Some comments were beyond the scope of the CMMC Program and are described but not addressed in this final rule. The majority of comments received were relevant and are summarized in the discussion and analysis section here. Additional comments were received in response to the CMMC supplemental documents published concurrently with the rule; the discussion and analysis of those comments is located at www.regulations.gov . Some comments received lacked relevance to the rule's content, which is limited to specific CMMC program requirements codified in the 32 CFR part 170 CMMC Program rule, responses for those comments are not provided. Any contractual requirements related to the CMMC Program rule will be implemented in the DFARS, as needed, which may result in revisions to the DFARS clause 252.204-7021, CMMC Requirements. DoD will address comments regarding the DFARS clause 252.204-7021 in a separate 48 CFR part 204CMM C Acquisition rulemaking. 1. Extension of the Public Comment Period Comment: DoD received requests from industry associations for an extension of the 60-day public comment period on the CMMC Proposed Rule that the Office of the Federal Register published on 26 December 2023. The length of extensions requested ranged from 30-60 days. Commenters argued that the proposed rule was initially published following a holiday, or more time was needed for associations to fully review member comments about the CMMC Proposed Rule prior to submitting. In addition, they argued that other rules pertaining to cyber incident reporting obligations and security of Federal Information Systems had also been published for public comment, which created a need for additional review time. Response: The DoD CIO denied requests for an extension of the 60-day public comment period. The DoD provided regular communication to the public through the DoD CMMC website and updates in the semiannual Unified Agenda in preparation for publication of the CMMC Proposed Rule to initiate the 60-day public comment period. The Department has an urgent need to improve DIB cybersecurity by further enforcing compliance with security requirements that were to be implemented by the DIB as soon as possible but not later than December 2017. 2. The CUI Program a. CUI Program Guidance Comment: Many comments were submitted related

to the NARA CUI policies or the DoD CUI Program, and while relevant for understanding CMMC requirements, those are separate policies or programs beyond the scope of the CMMC program or this rule. However, several comments recommended that the CMMC rule be revised to address them.

The estimated annual burden for a company to apply to the program or for a participating company to update POC information is \$36.31, with a total annual cost to all participants of \$319,498.67 at peak program participation. This calculation is based on 8,000 participants submitting an average of one application per year and 10% of the population (800 participants) submitting an update each year, with 20 minutes of labor per submission, at a cost of \$108.92 per hour ($\$36.31 (\$108.92 \times 1/3 \text{ hours}) \times 8,800 \text{ events} = \$319,498.67$). There is an estimated annual burden projected at \$544.60 for defense contractors voluntarily sharing cyber threat information. This is based on a defense contractor electing to submit an average of five informational reports per year with two hours of labor per voluntary submission, at a cost of \$108.92 per hour ($\$108.92 \times 2 \text{ hours each} = \$217.84 \times 5 \text{ reports} = \$1,089.20$). It is estimated that 1% of the newly eligible population will elect to join the DIB CS Program annually, which currently has approximately 1,000 participants, with program growth plateauing at 10% of the population by Year 9. The table below shows the costs to industry to voluntarily sharing cyber threat information over a 9-year period. If, in the first year of the program expanding there are 980 participants and 800 new participants join the program, there will be a total of 1,780 participants. Assuming each participant responds five times, this totals 8,900 annual responses times \$217.84 per response and will equal \$1,938,776 in total annual cost to participants, which is covered in information collection 0704-0489.

	Year 1	Year 2	Year 3	Year 4	Year 5	Year 6	Year 7	Year 8	Year 9
DIB CS Participants	1,780	2,580	3,380	4,180	4,980	5,780	6,580	7,380	8,000
Voluntary Reports Received	8,900	12,900	16,900	20,900	24,900	28,900	32,900	36,900	40,000
Annual Cost	\$1,938,776	\$2,810,136	\$3,681,496	\$4,552,856	\$5,424,216	\$6,295,576	\$7,166,936	\$8,038,296	\$8,713,600

In addition, DIB CS Program participants may choose to attend meetings in conjunction with the DIB CS Program. All new participants are invited to attend an orientation session and all existing participants are invited to attend meetings on a quarterly basis. If a defense contractor chooses to send an employee to a day-long meeting each quarter, the defense contractor would incur a cost of \$1,742 ($\$108.92 \times 8 \text{ hours} = \$871.36 \times 4 \text{ meetings} = \$3,485.44$). (printed page 27835)

Costs to the Government The DoD has identified general areas of costs related to the operation of this program. First, DoD incurs costs to implement this program operationally by responding to inquiries, processing application submissions and collecting, sharing, and managing POC information for program administration and management purposes. Second, DoD incurs costs to collect, analyze, and disseminate threat information.

(Response) FDA agrees that the use of warnings to the public about specific products is important. Indeed, FDA has used this approach many times. Nonetheless, records will ensure that FDA can perform trace forward to remove the problem food from the market and traceback to identify the source of the problem. These recordkeeping requirements will also enable FDA to identify the problem food more specifically and, thus, FDA can target its public warnings on the specific problematic food.

(Comment 6) A few comments request that the agency add a "pipeline provision" that allows the use of NA (not available) in place of information where ingredient records were not maintained. The comments state that many ongoing processing operations will have some ingredients on site that have been purchased and housed in facilities for some time prior to the implementation of these regulations. In these cases, it would be a significant manpower burden (or perhaps not possible at all) to obtain or attempt to recreate all the required information on the source of those ingredients. The comments note that these ingredients have been used in food production without incident and it would be unlikely they would be involved in an act of terrorism. (Response) There is no requirement to establish and maintain records for food ingredients you received before the compliance date of these regulations. Under that scenario, however, you must establish and maintain records of that food when you release it after the compliance date of the regulations. For example, if a commercial bread bakery receives flour, eggs, and salt before the compliance date of this final rule, it does not need to keep records of the immediate previous source of when it received that food. Once the bakery uses these ingredients to bake the bread and releases the bread to nonconsumers after the compliance date of the rule, the bakery must keep the records required by § 1.1345 of this final rule regarding the immediate subsequent recipients of the bread. (Comment 7) One comment recommends the use of United Code Council standards, a system of globally recognized and implemented standards that enables traceability of products and identification of trading parties/recipients, through all locations of the supply chain. (Response) FDA does not agree. The

agency has determined that the least burdensome way of issuing the recordkeeping requirements is to specify the information that must be contained in the records, but not the format in which the records are kept. Indeed, the agency received numerous comments that argued that covered entities should be allowed to use existing records and systems.

DoD's phased implementation of the CMMC Status requirements is described in §.170.3(e). Once CMMC requirements have been implemented in the DFARS, the solicitation and resulting contract will identify the specific CMMC Status required for that procurement. Selection of a CMMC Status will be based upon careful consideration of market research and the likelihood of a robust competitive market of prospective offerors capable of meeting the requirement. In some scenarios, DoD may elect to waive application of CMMC Status requirements to a particular procurement. In such cases, the solicitation will not include a CMMC Status requirement. Such waivers may be requested and approved by the Department in accordance with DoD's internal policies and procedures. For a DoD solicitation or contract that does include CMMC requirements, including those for the acquisition of commercial items (except those exclusively COTS items) valued at greater than the micro-purchase threshold, contracting officers will not make award, or exercise an option on a contract, if the offeror or contractor does not meet the requirements for the required CMMC Status. Furthermore, CMMC requirements are required to flow down to subcontractors as prescribed in the solicitation and resulting contract at all tiers, commensurate with the sensitivity of the unclassified information flowed down to each subcontractor.

B. Legal Authority 5 U.S.C. 301 authorizes the head of an Executive department or military department to prescribe regulations for the government of his or her department, the conduct of its employees, the distribution and performance of its business, and the custody, use, and preservation of its records, papers, and property (www.govinfo.gov/content/pkg/USCODE-2009-title5/pdf/USCODE-2009-title5-partI-chap3-sec301.pdf). Section 1648 of the National Defense Authorization Act for Fiscal Year 2020 (Pub. L. 116-92) [27] directs the Secretary of Defense to develop a consistent, comprehensive framework to enhance cybersecurity for the U.S. Defense Industrial Base (DIB). The CMMC Program is an important part of this framework.

C. Community Impact This final rule impacts all prospective and actual DoD contractors and subcontractors that are handling or will handle DoD information that meets the standards for FCI or CUI on a contractor information system during performance of the DoD contract or subcontract. This final rule also impacts all companies who are performing or will perform accreditation, training, certification, or assessment functions in connection with implementation of the CMMC Program.

D. Regulatory History

FIPS 199 defines security categories for information systems based on potential impact on organizations, assets, or individuals should there be a breach of security—that is, a loss of confidentiality, integrity, or availability. FIPS 199 security categories can play an important part in defining information system boundaries by partitioning the agency's information systems according to the criticality or sensitivity of the information and information systems and the importance of those systems in accomplishing the agency's mission. This is particularly important when there are various FIPS 199 impact levels contained in one information system. The FIPS 199 requirement to secure an information FIPS 200 provides seventeen minimum security requirements for federal information and information systems. The requirements represent a broad-based, balanced information security program that addresses the management, operational, and technical aspects of protecting the confidentiality, integrity, and availability of federal information and information systems. An agency must meet the minimum security requirements in this standard by applying security controls selected in accordance with NIST SP 800-53 and the designated impact levels of the information systems. An agency has the flexibility to tailor the security control baseline in accordance with the terms and conditions set forth in the standard. Tailoring activities include: (i) the application of scoping guidance; (ii) the specification of compensating controls; and (iii) the specification of agency-defined parameters in the security controls, where allowed. The system security plan should document all tailoring activities.

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.13.13E Port and Input/Output Device Access 1997 [Section (one): Physically; Logically] disable or remove [Assignment: organization-defined connection ports or input/output devices] on the following systems or system components: [Assignment: organization-defined systems or system components].

DISCUSSION Connection ports include Universal Serial Bus (USB), Thunderbolt, and Firewire (IEEE 1394). Input/output (I/O) devices include optical drives (e.g., compact disc and digital versatile disc drives), printers, and network attached storage devices. Disabling or removing such connection ports and I/O devices

helps prevent the exfiltration of information from systems and the introduction of malicious code from those ports or devices. Physically disabling or removing ports and/or

3.3.1 | Configuration... 3.3.1 Configuration - Remote Access: Cisco VPN - Configured to allow authorized VPN users to access to ConsoleWorks web interface. 3.3.1 eyeInspect 1.

(Comment 215) Several comments suggest that the recordkeeping requirements are so onerous that compliance periods should be extended to as many as 7 years. (Response) In the PRIA, FDA assumed that the recordkeeping provisions required a limited amount of additional information over current business practices. Comments suggest that this may not be true for certain provisions. In the final rule, we have relaxed some of the more costly provisions, such as the requirement for records to contain lot code information for all persons subject to the final rule, and we have relaxed the records access requirement to 24 hours. We have also revised the requirements applicable to transporters so that they have multiple options for complying with the final rule. These modifications should reduce the costs of compliance for small businesses. In addition, we have extended the compliance dates of the final rule by 6 months to 12, 18, and 24 months for large, small, and very small businesses. The extension should further reduce the costs of compliance with the final rule because the costs of the required changes in records quality and records access fall as compliance time increases. Moreover, given the purpose of the Bioterrorism Act, FDA believes a 7-year compliance period is excessive. (Comment 216) One comment states that large carriers account for only 0.28 percent of all carriers and that 0.28 percent of all carriers should not be unfairly burdened to comply with regulations 1 year before the rest. Another comment states that across-the-board compliance dates of 18 months better serves the purposes of the Bioterrorism Act, because it reflects the large volume of food that moves through big business. (Response) The Regulatory Flexibility Act requires that special consideration be given to small businesses when such flexibility does not compromise the efficacy of the regulation. In the PRIA, FDA considered several other potential flexibility options and found that the policy of staggering the compliance dates and exempting very small retailers were the only ones that did not appreciably compromise the effectiveness of the regulation. (Comment 217) Several comments state that large businesses would likely pass the costs of the regulation on to smaller firms. In addition, the proposed regulatory flexibility from staggered compliance dates would largely be ineffective, because large businesses will require their small suppliers to comply with the regulation to ensure their own compliance. Another comment suggests extending the compliance dates to 18 months for large businesses and 36 months to small businesses but acknowledged that staggering compliance dates would complicate business practices.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [Docket Number DARS-2020-0004; OMB Control Number 0704-0225] AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Notice. SUMMARY: The Defense Acquisition Regulations System has submitted to OMB for clearance, the following proposed revision and extension of a collection of information under the provisions of the Paperwork Reduction Act. DATES: DoD will consider all comments received by June 29, 2020. SUPPLEMENTARY INFORMATION: Title and OMB Number: Defense Federal Acquisition Regulation Supplement (DFARS), Part 204, Administrative Matters and Related Clause at 252.204; OMB Control Number 0704-0225. Type of Request: Revision and extension. Affected Public: Businesses or other for-profit and not-for profit institutions. Respondent's Obligation: Required to obtain or retain benefits. Number of Respondents: 545. Responses per Respondent: Approximately 5.57. Annual Responses: 3,036. Average Burden per Response: Approximately 3 hours. Annual Burden Hours: 9,108. Reporting Frequency: On occasion. Needs and Uses: DFARS 204.404-70(a) prescribes use of DFARS Clause 252.204-7000, Disclosure of Information, in contracts that require the contractor to access or generate unclassified information that may be sensitive and inappropriate for release to the public. The clause requires the contractor to obtain approval of the contracting officer before release of any unclassified contract-related information outside the contractor's organization, unless the information is already in the public domain. In requesting this approval, the contractor must identify the specific information to be released, the medium to be used, and the purpose for the release. Upon receipt of a contractor's request, the

Government reviews the information provided by the contractor to determine if it is sensitive or otherwise inappropriate for release for the stated purpose. Comments and recommendations on the proposed information collection should be sent to Ms. Jasmeet Sehra, DoD Desk Officer, at Oira_submission@omb.eop.gov. Please identify the proposed information collection by DoD Desk Officer and the Docket ID number and title of the information collection. You may also submit comments, identified by docket number and title, by the following method: Federal eRulemaking Portal: <http://www.regulations.gov>. Follow the instructions for submitting comments. DoD Clearance Officer:

DFARS 252.204-7008 (Compliance with Safeguarding CDI Controls) Requires offerors to represent that they will implement NIST SP 800-171 security requirements. DFARS 252.204-7008 works in conjunction with the CMMC program. While 252.204-7008 establishes the contractual requirement, CMMC (under 32 CFR Part 170) provides the assessment framework. Phase 1 began November 10, 2025, with Phase 2 (C3PAO certification requirements) scheduled for November 10, 2026.

3.1.3 of [1]) shall be generated using the pseudorandom key generation method specified in Algorithm 10' in Section 7.

Identify the system safeguards; for example, storage in safes, vaults, locked cabinets or rooms, use of guards, visitor controls, personnel screening, computer systems software, and so on. Describe safeguards fully without compromising system security. (n) Retention and Disposal. State how long AR 25-400-2 requires the activity to maintain the records. Indicate when or if the records may be transferred to a Federal Records Center and how long the record stays there. Specify when the Records Center sends the record to the National Archives or destroys it. Indicate how the records may be destroyed. (o) System Manager(s) and Address: List the position title and duty address of the system manager. For decentralized systems, show the locations, the position, or duty title of each category of officials responsible for any segment of the system. (p) Notification Procedures: List the title and duty address of the official authorized to tell requesters if their records are in the system. Specify the information a requester must submit; for example, full name, military status, SSN, date of birth, or proof of identity, and so on. (q) Record Access Procedures: Explain how individuals may arrange to access their records. Include the titles or categories of officials who may assist; for example, the system manager. (r) Contesting Records Procedures: The standard language to use is 'The Army's rules for accessing records, and for contesting contents and appealing initial agency determinations are contained in Army Regulation 25-71; 32 CFR part 505 ; or may be obtained from the system manager.' (s) Record Source Categories: Show categories of individuals or other information sources for the system. Do not list confidential sources protected by 5 U.S.C. 552a(k)(2) , (k)(5), or (k)(7). (t) Exemptions Claimed for the System: Specifically list any approved exemption including the subsection in the Act. When a system has no approved exemption, write 'none' under this heading. Appendix G to Part 505 Management Control Evaluation Checklist (a) Function. The function covered by this checklist is DA Privacy Act Program. (b) Purpose. The purpose of this checklist is to assist Denial Authorities and Activity Program Coordinators in evaluating the key management controls listed below. This checklist is not intended to cover all controls. (printed page 46070) (c) Instructions. Answer should be based on the actual testing of key management controls (e.g., document analysis, direct observation, sampling, simulation, other). Answers that indicate deficiencies should be explained and corrective action indicated in supporting documentation. These management controls must be evaluated at least once every five years. Certificate of this evaluation has been conducted and should be accomplished on DA Form 11-2-R (Management Control Evaluation Certification Statement). Test Questions a. Is a Privacy Act Program established and implemented in your organization?

(n) Retention and Disposal. State how long AR 25-400-2 requires the activity to maintain the records. Indicate when or if the records may be transferred to a Federal Records Center and how long the record stays there. Specify when the Records Center sends the record to the National Archives or destroys it. Indicate how the records may be destroyed. (o) System Manager(s) and Address: List the position title and duty address of the system manager. For decentralized systems, show the locations, the position, or duty title of each category of officials responsible for any segment of the system. (p) Notification Procedures: List the title and duty address of the official authorized to tell requesters if their records are in the system. Specify the information a requester must submit; for example, full name, military status, SSN, date of birth, or proof of identity, and so on. (q) Record Access Procedures: Explain how individuals may arrange to access their records.

Include the titles or categories of officials who may assist; for example, the system manager. (r) Contesting Records Procedures: The standard language to use is "The Army's rules for accessing records, and for contesting contents and appealing initial agency determinations are contained in Army Regulation 25-71; 32 CFR part 505 ; or may be obtained from the system manager." (s) Record Source Categories: Show categories of individuals or other information sources for the system. Do not list confidential sources protected by 5 U.S.C. 552a(k)(2) , (k)(5), or (k)(7). (t) Exemptions Claimed for the System: Specifically list any approved exemption including the subsection in the Act. When a system has no approved exemption, write "none" under this heading. (printed page 24512) Appendix G to Part 505-Management Control Evaluation Checklist (a) Function. The function covered by this checklist is DA Privacy Act Program. (b) Purpose. The purpose of this checklist is to assist Denial Authorities and Activity Program Coordinators in evaluating the key management controls listed below. This checklist is not intended to cover all controls. (c) Instructions. Answer should be based on the actual testing of key management controls (e.g., document analysis, direct observation, sampling, simulation, other). Answers that indicate deficiencies should be explained and corrective action indicated in supporting documentation. These management controls must be evaluated at least once every five years. Certificate of this evaluation has been conducted and should be accomplished on DA Form 11-2-R (Management Control Evaluation Certification Statement). Test Questions. a. Is a Privacy Act Program established and implemented in your organization? b. Is an individual appointed to implement the Privacy Act requirements?

This rule promotes uniformity in the DoD Privacy Program across the entire Department and provides notice of DoD's privacy procedures as well as other privacy protections to the public with no increase in costs on the public. This streamlined rule addresses Department procedures concerning notification of, access to, and amendment of records covered by the Privacy Act, as well as requests for accounting of disclosures of such records. It also addresses exemptions from provisions of the Privacy Act and incorporates all Department exemption rules. The following sections of the previous rule have also been removed: Subpart A: §-310.1 Reissuance, §-310.3 Applicability and scope, §-310.5 Policy, §-310.6 Responsibilities, §-310.8 Rules of Conduct, and §-310.9 Privacy boards and office, composition and responsibilities; Subpart B-System of Records; Subpart C-Collecting Personal Information; Subpart E-Disclosure of Personal Information to Other Agencies and Third Parties; Subpart G-Publication Requirements; Subpart H-Training Requirements; Subpart I-Reports; Subpart J-Inspections; Subpart K-Privacy Act Violations (portions of this section can now be found in the current §-310.8);, Subpart L-Computer Matching Program Procedures; and all of Appendices A-H. These sections largely consist of internal policy guidance to DoD personnel and are more appropriately addressed in DoD 5400.11-R, "Department of Defense Privacy Program," available at <http://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodm/540011r.pdf> . To the extent that existing provisions of DoD 5400.11-R conflict with current OMB guidance or this updated Part 310, OMB guidance and this Part shall control. This rule also incorporates into §-310.13 the final version of the exemption rule first published on October 17, 2018 (83 FR 52317 ; docket DOD-2018-OS-0075-0001) as an interim final rule, claiming certain Privacy Act exemptions for the Personnel Vetting Records System (83 FR 52420) Authority: The Privacy Act, 5 U.S.C. 552a , requires each agency that maintains a system of records to promulgate rules, pursuant to notice and public comment according to 5 U.S.C. 552a(f) "Agency Rules." Expected Cost Savings DoD currently has 20 other separate component-level privacy rules. Following publication of this final rule, DoD will repeal all component-level privacy rules. This rulemaking will reduce costs and time for the public by consolidating the requirements for requests for access to and amendment of DoD information.

esses at the organization level. In addition, it establishes responsibility and accountability for the controls implemented within an organization's information systems and inherited by those systems. assess; authorization to operate; authorization to use; authorizing official; categorize; common control; common control authorization; common control provider; continuous monitoring; control assessor; control baseline; cybersecurity framework profile; hybrid control; information owner or steward; information security; monitor; ongoing authorization; plan of action and milestones; privacy; privacy assessment report; privacy control; privacy plan; privacy risk; risk assessment; risk executive function; risk management; risk management framework; security; security assessment report; security control; security engineering; security plan; security risk; senior agency information security officer; senior agency official for privacy; supply chain risk management; system development life cycle; system owner; system privacy officer; system security officer; system-specific control.

Nonrecurring Engineering Costs: Estimates consist of hardware, software, and the associated labor to implement the same. Costs associated with implementing the requirements defined in FAR 52.204-21 and NIST SP 800-171 Rev 2 are assumed to have been implemented and, therefore, are not accounted for in this cost estimate. As such, these costs only appear in CMMC Level 3. If nonrecurring engineering costs are referenced, they are only accounted for as a one-time occurrence and are reflected in the year of the initial assessment. Recurring Engineering Costs: Estimates consist of annually recurring fees and associated labor for technology refresh. Costs associated with implementing the requirements defined in FAR 52.204-21 and NIST SP 800-171 Rev 2 are assumed to have been implemented and, therefore, are not accounted for in this cost estimate. As such, these costs only appear in CMMC Level 3. Assessment Costs: Estimates consist of activities for pre-assessment preparations (which includes gathering and/or developing evidence that the assessment objectives for each requirement have been satisfied), conducting and/or participating in the actual assessment, and completion of any post-assessment work. Assessment costs are represented by notional phases. Assessment costs assume the company passes the assessment on the first attempt (conditional with an allowable POA&M or final). Each phase includes an estimate of hours to conduct the assessment activities including: (printed page 89107) (c) Labor Hour Estimates for a Company (and any ESP Support) To Prepare for and Participate in the Assessment (d) C3PAO Cost Estimates for Companies Pursuing a Certification Labor hour estimates for certified or authorized assessors to work with the small business to conduct the actual assessment. (e) Assessment Costs Broken Down Into Phases Phase 1: Planning and preparing for the assessment. Phase 2: Conducting the assessment (self or C3PAO). Phase 3: Reporting of Assessment Results. Phase 4: POA&M Closeout (for CMMC Level 3 only, where allowed, if applicable). CMMC allows a limited open Plan of Action and Milestones (POA&M) for a period of 180 days to remediate the POA&M, see 32 CFR 170.21 . Affirmations: Estimates consist of costs for a contractor or subcontractor to submit to SPRS an initial affirmation of compliance that the contractor information system is compliant with and will maintain compliance with the requirements of the applicable CMMC Level. If POA&Ms are allowed, an affirmation must be submitted with the POA&M closeout. With the exception of Small Entities for Level 1 and Level 2, it is assumed the task requires the same labor categories and estimated hours as the final reporting phase of the assessment. The categories and rates used for estimating purposes were compiled by subject matter experts based on comparable industry data and are defined in the table. (c) Cost Analysis/Estimates by CMMC Level CMMC Level 1 Self-Assessment and Affirmation Costs for Small Business Entities

), which states that, in any action to enforce the FD&C Act's requirements respecting foods, drugs, devices, and cosmetics, any necessary connection with interstate commerce is presumed. Likewise, this outcome is consistent with Congress's goal in enacting the Bioterrorism Act, because the potential harm from bioterrorist attacks or other food-related emergencies can be great, whether or not the food moves from one State to another. The usefulness of recordkeeping also can be significant in food emergencies where interstate shipment has not occurred. 3. Foreign Facilities (Comment 25) Several comments assert that FDA lacks the statutory authority to apply the recordkeeping and records inspection provisions of the Bioterrorism Act to foreign facilities. According to the comments, section 306 of the Bioterrorism Act does not indicate, expressly or by inference, that Congress intended the provisions of that section to apply to overseas persons or facilities. They also contend that nothing in the legislative history of the Bioterrorism Act indicates Congress intended that section 306 of the Bioterrorism Act should apply to foreign facilities. The comments point out that there is a longstanding presumption in the law that legislation does not apply outside the borders of the United States, unless Congress clearly and expressly states such an intent. The comments state that, under governing case law, FDA may not infer legislative intent to give a statute extraterritorial reach. A few comments indicated that FDA failed to provide legal justification for applying the regulation to foreign facilities. The comments pointed out that FDA's stated belief that this was the most efficient and effective strategy for obtaining needed information on food from foreign countries cannot overcome the clear indications that Congress did not intend section 306 of the Bioterrorism Act to apply to foreign entities. One comment suggests that FDA clarify that the recordkeeping requirements do not apply outside of the United States, but serve only as a guideline to facilitate a rapid response through cooperation at intergovernment and international industry levels. One comment states that it has been acknowledged in the context of recent CBP initiatives that CBP has no jurisdiction in foreign countries. The comment notes that, consequently, mutual agreements on cooperation between CBP and some foreign governments have been reached to address together their shared security objectives.

Comments suggested that FDA pursue a similar approach for safety and security of foods.

(2) OSCs must submit an affirmation of compliance into SPRS, as specified in paragraph (a)(2) of this section. (c) Procedures. (1) Assessment. The CMMC Level 3 Certification Assessment process includes: (i) CMMC Level 2 Final Certification Assessment. CMMC Level 2 Final Certification Assessment must be obtained for information systems within the Level 3 CMMC Assessment Scope prior to assessment against the CMMC Level 3 security requirements of NIST SP 800-172A (incorporated by reference, see § 170.2). The OSC must have a CMMC Level 2 Final Certification Assessment for the same scope as the Level 3 assessment. Asset requirements differ for each CMMC Level. Scoping differences are set forth in § 170.19(e). (ii) CMMC Level 3 Certification Assessment. DCMA DIBCAC will perform an assessment of the CMMC Level 3 security requirements in accordance with NIST SP 800-172A for information systems within the Level 3 CMMC Assessment Scope, determined in accordance with § 170.19(d). The assessment will be scored in accordance with the CMMC Scoring Methodology set forth in § 170.24 and final results are subsequently communicated to the OSC through a CMMC Assessment Findings Report. In the execution of the CMMC Level 3 Certification Assessment, DCMA DIBCAC may perform checks of CMMC Level 2 security requirements in accordance with CMMC Level 3 scoping. If DCMA DIBCAC identifies that a Level 2 security requirement is NOT MET, the Level 3 assessment process may be placed on hold or terminated. (2) Security requirement re-evaluation. A security requirement under assessment that is NOT MET may be re-evaluated during the course of the assessment and for 10 business days following the active assessment period if all of the following conditions exist: (i) Additional evidence is available to demonstrate the security requirement has been MET; (ii) The additional evidence does not materially impact previously assessed security requirements; and (iii) The CMMC Assessment Findings Report has not been delivered. (3) POA&M. If a POA&M exists after the initial assessment, a POA&M closeout assessment will be performed by DCMA DIBCAC when all remaining security requirements have been implemented. The POA&M closeout assessment must be performed within the 180-day closeout period to achieve the assessment requirement for Final Certification. Additional guidance is located in § 170.21 and in the guidance document listed in paragraph (a) of appendix A to this part. (4) Artifact retention and integrity.

The NATO has a registry system for the receipt and distribution of NATO documents within each NATO member nation. The central distribution point for the United States is the CUSR now located at 9301 Chapek Road, Building 1458, Fort Belvoir, Virginia 22060. (i) The CUSR establishes sub registries at USG organizations for further distribution and control of NATO documents. Sub registries may establish control points at contractor facilities. (ii) COSMIC TOP SECRET, NATO SECRET, and all ATOMAL documents will be transferred through the registry system. NATO CONFIDENTIAL documents provided as part of NATO infrastructure contracts will be transmitted via government channels in compliance with paragraph (d) in this section. (15) Hand carrying. NATO SECRET and NATO CONFIDENTIAL documents may be hand carried across international borders if authorized by the GCA. The courier will be issued a NATO Courier Certificate by the CSA. When hand carrying is authorized, the documents will be delivered to a U.S. organization at NATO, which will transfer them to the intended NATO recipient. (16) Reproduction. Reproductions of COSMIC TOP SECRET and COSMIC TOP SECRET ATOMAL information will be performed by the responsible Registry. The reproduction of NATO SECRET and CONFIDENTIAL documents may be authorized to meet contractual requirements unless reproduction is prohibited by the contracting entity. Copies of COSMIC TOP SECRET, NATO SECRET, and ATOMAL documents will be serially numbered and controlled and accounted for in the same manner as the original. (17) Disposition. (i) Generally, all NATO classified documents will be returned to the contracting activity that provided them on completion of the contract. Documents provided in connection with an invitation to bid also will be returned immediately if the bid is not accepted or submitted. (ii) NATO classified documents may also be destroyed when permitted. COSMIC TOP SECRET and COSMIC TOP SECRET ATOMAL documents will be destroyed by the registry that provided the documents. (A) Destruction certificates are required for all NATO classified documents except NATO CONFIDENTIAL. (B) The destruction of COSMIC TOP SECRET, NATO SECRET, and all ATOMAL documents must be witnessed. (18) Accountability records. Logs, receipts, and destruction certificates are required for NATO classified information. Records for NATO documents will be maintained separately from records of non-NATO documents (methods such as separate drawers of a container). (i) COSMIC TOP SECRET and all ATOMAL documents will be recorded on logs maintained separately from other NATO logs and will be assigned unique serial control numbers. (ii) Additionally, disclosure records bearing the name and signature of each person who has access are required for all COSMIC TOP SECRET, COSMIC TOP SECRET ATOMAL, and all other ATOMAL or NATO classified documents to which special access limitations have been applied.

Several respondents commented on the need for the rule to specify relevant supply chain risk management (SCRM) standards, controls, etc. One respondent stated that while it does not suggest DoD explicitly endorse one set of controls over another, industry does need some guidance beyond maintain controls. There must be consistency in the call out of the relevant SCRM standards and ratings in solicitations so as not to create an unnecessary administrative burden for contractors to select suppliers and subcontractors based on a moving target of standards and ratings.

Notwithstanding making a reference to the Regulatory Flexibility Act on page 69269 in the narrative of the Federal Register document that the rule recognizes the need for information technology contractors to implement appropriate safeguards and countermeasures to minimize supply chain risk, one respondent commented that the interim rule does not provide any guidance about what metric will be applied to its products, services, and business models. The respondent further stated that the rule requires contractors to maintain controls in the provision of supplies and services to the Government to minimize supply chain risk but does not provide any guidance to contractors or Government contracting officers as to the type of controls to be maintained to meet this requirement, recommending that DoD issue additional guidance that uses existing and proposed global, consensus-based standards. One respondent commented that the absence of what standard DoD will use to evaluate supply chain risks is likely to increase the time and cost of pursuing and performing Government contracts. Response: The final rule removes the language requiring contractors to (printed page 67247) maintain controls and now states that the contractor shall mitigate supply chain risk in the provision of supplies and services to the Government. This change was made because the DFARS cannot identify specific standards or controls as this would be up to each requiring activity to identify if any standards or controls are necessary particular to the risks and risk tolerance that would apply to each procurement. DoD continues to work with industry to identify risk management best practices and promulgate best practice documents for consideration.

f. Verification/Inspection Comment: One respondent commented that suppliers should meet the requirement to provide supply chain security verification by documentation, suggesting that all levels of the supply chain Government, prime contractors, subcontractors, and parts suppliers should be in compliance with supply chain integrity requirements and have records and production locations available for inspection if necessary. Response: The practices, documentation, and information suggested in the comment are important tools in protecting against supply chain risk. However, these suggestions do not comply with the legislative requirements to implement section 806.

5. Process

a. General Comment:

that would be associated with the proposed standard for patch management. The proposed implementation specification for policies and procedures at proposed paragraph (a)(4)(ii)(A) would require a regulated entity to establish written policies and procedures for identifying, prioritizing, acquiring, installing, evaluating, and verifying the timely installation of patches, updates, and upgrades throughout its electronic information systems that create, receive, maintain, or transmit ePHI or that otherwise affect the confidentiality, integrity, or availability of ePHI.

Under the proposed implementation specification for maintenance at proposed paragraph (a)(4)(ii)(B), a regulated entity would be required to review its patch management written policies and procedures at least once every 12 months and modify them as reasonable and appropriate based on that review.

The proposed implementation specification for application at proposed paragraph (a)(4)(ii)(C) would require a regulated entity to patch, update, and upgrade the configurations of its relevant electronic information systems in accordance with its written policies and procedures and based on the results of: the regulated entity's risk analysis that would be required by proposed 45 CFR 164.308(a)(2), the vulnerability scans that would be required under proposed 45 CFR 164.312(h)(2)(i), the monitoring of authoritative sources that would be required under proposed 45 CFR 164.312(h)(2)(ii), and penetration tests proposed at 45 CFR 164.312(h)(2)(iii). The proposal would require that such actions be taken within a reasonable and appropriate period of time, except to the extent that an exception in proposed paragraph (h)(2)(ii)(D) applies.

Specifically, a reasonable and appropriate period of time to patch, update, or upgrade the configuration of a relevant electronic information system would be within 15 calendar days of identifying the need to address a critical risk where a patch, update, or upgrade is available; or, where a patch, update, or upgrade is not available, within 15 calendar days of a patch, update, or upgrade becoming available. The proposal would require that, within 30 calendar days of identifying the need to address a high risk, [498] a regulated entity patch, update, or upgrade the configuration of a relevant electronic information system where a patch, update, or upgrade is available; or, where a patch, update, or upgrade is not available, within 30 calendar days of a

patch, update, or upgrade becoming available. For all other patches, updates, or upgrades to the configurations of relevant electronic information systems, a reasonable and appropriate period of time would be determined by the regulated entity's written policies and procedures for identifying, prioritizing, acquiring, installing, evaluating, and verifying the timely installation of patches, updates, and upgrades.

program management, review of security controls, risk management, security awareness training and education (including specific training course and awareness materials), and security planning, including OCR's enforcement of the HIPAA Security and Privacy rules; techniques for developing risk assessments and contingency planning; breach notification; the security of health devices; and security considerations for the use of new media and wireless technologies in healthcare environments.

Control EQ-1: be easy to integrate | Provide a Mechanism for Verifying Software Release Integrity (PS.2): Help software acquirers ensure that the software they acquire is legitimate and has not been tampered with. | 5.2.1 Secure CD Pipeline -Case Study (GitOps) | The following SSC security tasks should be applied when creating configuration data prior to deployment, capturing all data pertaining to a particular release, modifying software during runtime, and performing monitoring operations: · GitOps-REQ-2: Package managers that facilitate GitOps should preserve all data on the packages that were released, including the version numbers of all modules, all associated configuration files, and other metadata as appropriate for the software operational environment. | Archive and Protect Each Software Release (PS.3): Preserve software releases in order to help identify, analyze, and eliminate vulnerabilities discovered in the software after release.

Many individual considerations for cybersecurity and privacy were discussed. One consistent point of discussion was the scope and scale of data needed to make immersive technologies function. Specifically, the community highlighted that the context in which data processing takes place and privacy and cybersecurity risks arise (i.e., immersive worlds powered by granular biometric, spatial, and behavioral/emotional data) is unique to immersive technologies. Privacy and cybersecurity impacts may be amplified by immersive technologies due to the nature and scale of data processing. Novel types of data processing activities include biometrics for uses other than identity management, real-time spatial mapping, and the The community recommended several areas related to immersive technologies that could benefit from additional standardization efforts. Usability is a hurdle for hardware and software standards (e.g., ways to manage multiple accounts within the same device). Identity standards for immersive tech could be helpful to address this. Standards for trustworthy AI (e.g., watermarking and other content authentication) would be welcomed.

(b) FIPS PUB 201-3, titled ·Personal Identity Verification (PIV) of Federal Employees and Contractors· establishes a standard for a PIV system that meets the control and security objectives of Homeland Security Presidential Directive-12. It is based on secure and reliable forms of identity credentials issued by the Federal Government to its employees and contractors. These credentials are used by mechanisms that authenticate individuals who require access to federally controlled facilities, information systems, and applications. This Standard addresses requirements for initial identity proofing, infrastructure to support interoperability of identity credentials, and accreditation of organizations and processes issuing PIV credentials. This document is incorporated by reference as a source for definitions. (c) NIST SP 800-37, revision 2, titled ·Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy· describes the Risk Management Framework (RMF) and provides guidelines for applying the RMF to information systems and organizations. The RMF provides a disciplined, structured, and flexible process for managing security and privacy risk that includes information security categorization; control selection, implementation, and assessment; system and common control authorizations; and continuous monitoring. The RMF includes activities to prepare organizations to execute the framework at appropriate risk management levels. The RMF also promotes near real-time risk management and ongoing information system and common control authorization through the implementation of continuous monitoring processes; provides senior leaders and executives with the necessary information to make efficient, cost-effective, risk management decisions about the systems supporting their missions and business functions; and incorporates security and privacy into the system development life cycle. Executing the RMF tasks links essential risk management processes at the system level to risk management processes at the organization level. In addition, it establishes responsibility and

accountability for the controls implemented within an organization's information systems and inherited by those systems. This document is incorporated by reference as a source for definitions. (d) NIST SP 800-39, titled "Managing Information Security Risk: Organization, Mission, and Information System View" provides guidance for an integrated, organization-wide program for managing information security risk to organizational operations (i.e.,

While the Department disagrees with the court's interpretation that merely requiring employees to sign an agreement to encrypt portable devices is sufficient to comply with its Security Rule obligations to implement a mechanism to encrypt and decrypt ePHI, the Department believes that additional clarity is warranted to ensure that regulated entities understand their obligation to have encryption mechanisms in place and deployed throughout the regulated entity's enterprise to ensure the confidentiality, integrity, and availability of ePHI. Several technical safeguards currently require regulated entities to implement a "mechanism" as part of complying with the associated standard. Given that written policies and procedures alone are insufficient to protect ePHI, and the misinterpretation of what it means to implement a mechanism also could lead to inadequate protection of ePHI, the Department believes that the Security Rule must be revised, consistent with its statutory mandate, as discussed in greater detail above. D. It Is Reasonable and Appropriate To Strengthen the Security Rule To Address the Changes in the Health Care Environment and Clarify the Compliance Obligations of Regulated Entities 1. Congress and the Department Anticipated That Security Standards Safeguards Would Evolve To Address Changes in the Health Care Environment By requiring that regulated entities maintain reasonable and appropriate safeguards to protect against reasonably anticipated threats or hazards or unauthorized uses or disclosures of ePHI, Congress clearly anticipated that the administrative, physical, and technical safeguards implemented to protect the security of ePHI would need to change in response to changes in the environment in which health care is provided. [261] As the health care environment and the operations of regulated entities evolve, so must the protections for ePHI and the information systems used to create, receive, maintain, or transmit it. For example, regulated entities must be expected to adopt safeguards that address new risks to the security of ePHI, such as those posed by maintaining ePHI in the cloud; the connection of medical devices and other technology to networks; and the connection of information systems used to create, receive, maintain, or transmit ePHI to the same networks as those do not perform such activities. After all, it is reasonable to anticipate that there will be new threats or hazards to ePHI or efforts by unauthorized persons to use or disclose such ePHI in an increasingly connected environment.

As part of standing up version 1 of the CMMC Program, the Department of Defense published a DFARS interim final rule, "Assessing Contractor Implementation of Cybersecurity Requirements" in the Federal Register on September 29, 2020 (85 FR 61505). The Department received approximately 750 comments on the DFARS interim final rule pertaining to elements of the CMMC Program that are now being addressed in this rule. Those comments are summarized and addressed in the discussion and analysis. In addition to comments on elements of the CMMC Program, DoD also received comments on the associated DFARS text, solicitation provisions, and contract clauses relating to the CMMC Program. The CMMC Program requirements proposed in this rule will be implemented in the DFARS, as needed, which may result in changes to current DoD solicitation provisions and contract clauses relating to DoD's cybersecurity protection requirements, including DFARS clause 252.204-7021, CMMC Requirements. DoD will address comments regarding the DFARS clause 252.204-7021 in a separate 48 CFR rulemaking. 1. Service Providers Comment: Multiple commenters asked about applicability of the CMMC Program to a variety of service providers. One commenter requested clarification regarding how CUI controls apply to internet Service Providers and their globally sourced service support because of the prohibition of foreign dissemination for CUI. Two commenters suggested that common carrier telecommunications (often termed as Plain-Old-Telephone-Services (POTS)) and similar commercial services (cloud services, external service providers) should be treated as commercial off-the-shelf (COTS), and so excluded from CMMC certification requirements. One commenter expressed concerns about the impact of the rule on the telecom industry. One commenter recommended that, to limit the burden of CMMC implementation, contractors providing commercial services to support COTS items, such as technical support for software, should receive the same exceptions as other COTS contracts. Response: The CMMC Program will result in cybersecurity protection and assessment requirements for defense contractors and subcontractors. CMMC Level requirements will apply only if a defense contractor or subcontractor handles FCI or CUI on its own contractor information systems. If so, then under CMMC, the contractor or subcontractor will be required to comply with the cybersecurity protection and assessment requirements associated with the appropriate Level. As such, CMMC Level

requirements will not apply to internet Service Providers or other telecommunications service providers (i.e., common carriers), unless those entities themselves are or intend to become defense contractors or subcontractors. In addition, there is no general prohibition of foreign dissemination for CUI, although certain CUI may be subject to export restrictions. Commercial item determinations per 48 CFR 15

One commenter presumed that only U.S.-based Cloud Service Providers (CSPs) may become FedRAMP authorized, and asserted a need to authorize or accredit foreign-based CSPs that foreign DIB contractors might use while still achieving CMMC compliance. Another asked how foreign small businesses can comply with CMMC without access to U.S. approved CSPs. One commenter asked for guidance on how to get foreign products and services, such as encryption and decryption mechanisms, approved for use in information systems that require CMMC assessment. One commenter suggested that the CMMC program permit assessment by C3PAOs and assessors accredited in accordance with other ISO/IEC standards than those identified in this rule. They cited ISO/IEC 27001 or 9901 as suitable alternate ISO/IEC standards. Response: The DoD declines to delay CMMC Program implementation for non-U.S. organizations. International businesses will not receive special accommodations because the CMMC Program's phased implementation will impact both U.S. and non-U.S. defense contractors equally. The implementation plan described in the rule does not promote or prioritize certification assessments of any contractor over any other contractor. All companies, regardless of location or nationality, will have access to any authorized C3PAO. The rule does not preclude non-U.S. citizens or foreign-owned C3PAOs from operating in the U.S. Additionally, U.S. owned C3PAOs may operate in a foreign nation. As stated in the rule, C3PAOs must meet the criteria in §.170.9. Non-U.S. organizations and employees that meet all the requirements in §§.170.9 and 170.11 will not be prohibited from operating as a C3PAO within the U.S. or abroad. A list of authorized C3PAOs is available on the current CMMC AB marketplace. DoD does not concur with the recommendation to delete §.170.9(b)(5) content identifying FOCI requirements. Those details for complying with FOCI are necessary for understanding the requirement. Some commenters noted differences between the rule content and information on the CMMC AB website. The CMMC AB is part of the public and had no access to advance information prior to publication of the proposed rule. The rule takes precedence in the event of any discrepancy with CMMC AB materials. The document `Career Pathway Certified Assessor 612', dated 2020, has been replaced by a regularly updated DoD Cyberspace Workforce Framework which may be found at <https://public.cyber.mil/dcwf-work-role/security-control-assessor/> . Intermediate and Advanced Foundational Qualification Options in the DoD Cyberspace Workforce Framework's Security Control Assessor (612) Work Role are available to foreign nationals. The rule has been updated to reflect this reference update.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation-s measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL-s responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in Federal information systems.

EXECUTIVE SUMMARY
..... IX Content of the Report
..... xi CHAPTER 1
DOCUMENT DEVELOPMENT STRATEGY1
1.1 Cybersecurity and the Electric Sector
..... 4 1.2
Scope and Definitions
..... 5 1.3 Smart Grid Cybersecurity Document Development Strategy
..... 6 1.4 Combined Cyber-Physical Attacks
..... 12
CHAPTER 2 LOGICAL ARCHITECTURE AND INTERFACES OF THE SMART GRID14 2.1 The
Seven Domains to the Logical Reference Model
..... 15 2.2 Logical Security
Architecture Overview
.....

(i) One safeguard plan is the development and use of a Privacy Impact Assessment (PIA) mandated by

the E-Gov Act of 2002, Section 208. The Office of Management and Budget specifically directs that a PIA be conducted, reviewed, and published for all new or significantly altered information in identifiable form collected from or about the members of the public. The PIA describes the appropriate administrative, technical, and physical safeguards for new automated systems. This will assist in the protection against any anticipated threats or hazards to the security or integrity of data, which could result in substantial harm, embarrassment, inconvenience, or unfairness to any individual on whom information is maintained. Contact your local Information Officer for guidance on conducting a PIA. (ii) The development of appropriate safeguards must be tailored to the requirements of the system as well as other factors, such as the system environment, location, and accessibility. § 505.4 Collecting personal information. (a) General provisions. (1) Employees will collect personal information to the greatest extent practicable directly from the subject of the record. This is especially critical, if the information may result in adverse determinations about an individual's rights, benefits, and privileges under federal programs (See 5 U.S.C. 552a(e)(2)). (2) It is unlawful for any Federal, State, or local government agency to deny anyone a legal right, benefit, or privilege provided by law for refusing to give their SSN unless the law requires disclosure, or a law or regulation adopted before January 1, 1975, required the SSN or if DA uses the SSN to verify a person's identity in a system of records established and in use before that date. Executive Order 9397 (issued prior to January 1, 1975) authorizes the Army to solicit and use the SSN as a numerical identifier for individuals in most federal records systems. However, the SSN should only be collected as needed to perform official duties. Executive Order 9397 does not mandate the solicitation of SSNs from Army personnel as a means of identification.

Back to Citation 48. ·A person needs to enter the information into SPRS, which should only take five minutes. Back to Citation 49. ·DoD utilized subject matter expertise from Defense Pricing and Contracting (DPC) and DCMA DIBCAC to estimate the Nonrecurring and Recurring Engineering Costs. Back to Citation 50. ·Costs for closing out POA&Ms are included at Level 3 because the requirement to implement a subset of NIST SP 800-172 Feb2021 security requirements is new with the CMMC rule. These costs are not included at Level 2 because the implementation of all NIST SP 800-171 R2 security requirements are already required. Back to Citation 51. ·Costs for closing out POA&Ms are included at Level 3 because the requirement to implement a subset of NIST SP 800-172 Feb2021 security requirements is new with the CMMC rule. These costs are not included at Level 2 because the implementation of all NIST SP 800-171 R2 security requirements is already required. Back to Citation 52. ·Nonrecurring engineering costs were first incurred in FY20. The cost has inflation applied to put the value in 2023 base year (BY) dollars. Back to Citation 53. ·The cost for the recurring engineering cost is based on the costs incurred in FY20 and FY21. The values for Year 1 (FY20) and Year 2 (FY21) are actual historic values that have inflation applied to them to put them in base year 2023 dollars. Every proceeding years' recurring engineering cost is based on the average of the two historic actual values. Back to Citation 54. www.govinfo.gov/content/pkg/CHRG-113hhrg86391/html/CHRG-113hhrg86391.htm . Back to Citation 55. www.nbr.org/program/commission-on-the-theft-of-intellectual-property/ . Back to Citation 56. www.cybernc.us/fci-cui/ . Back to Citation 57. ·GAO Report to Congress, Defense Contractor Cybersecurity Stakeholder Communication and Performance Goals Could Improve Certification Framework, December 2021. Back to Citation 58. www.cisa.gov/news-events/cybersecurity-advisories/aa22-047a . Back to Citation 59. www.whitehouse.gov/briefing-room/statements-releases/2022/03/21/statement-by-president-biden-on-our-nations-cybersecurity/ . Back to Citation 60. www.gsa.gov/technology/it-contract-vehicles-and-purchasing-programs/technology-products-services/it-security/executive-order-14028 . Back to Citation 61. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-171A.pdf> . Back to Citation 62. ·DoD estimates of the hours, recurring and non-recurring costs, and labor rates are based upon subject matter expertise from the DOD Chief Information Office, CMMC Program Office, and DoD/DIBCAC. Back to Citation 63. ·Again, it is assumed that that DIB contractors and subcontractors have already implemented the 15 basic safeguarding requirements in FAR clause 52.204-21. Back to Citation 64. ·An external service provider is assumed to be an Information Assurance Specialist Level 7 with an hourly rate of \$260. Back to Citation

No longer draft, coordinate and submit proposed national interest determinations (NIDs) for access to proscribed information for the small number of U.S. contractors with NTIB ownership operating under an SSA. There will be a small cost savings because DoD Components (i.e., Departments of the Army, Navy and Air Force, DARPA, DIA, NSA, NRO, NSA and assorted smaller organizations) will no longer have to take an estimated 40 hours a year to draft, coordinate and submit NIDs for the small

number of U.S. contractors with NTIB ownership operating under an SSA. There will be minimal administrative changes to the DoD information system to remove the NID requirement for the small number of NTIB covered entities. DoD already must evaluate any changes submitted to FOCI information for U.S. cleared legal entities under its security cognizance which would include a determination if one of these cleared legal entities remains a covered NTIB entity. On average, DoD receives an estimated one FOCI changed condition report annually from an NTIB covered cleared legal entity. An estimated 10 government personnel with an estimated labor rate of a GS11 step 5 would save 40 hours in year 1 through year 20. These assumptions imply costs saving of approximately \$28 thousand each year. e. Update training materials, job aids and associated tools for U.S. cleared legal entities and USG agencies on these changes to the NISPOM. CSAs will have to update existing training materials and products used by U.S. cleared legal entities and USG agencies so that they have all needed information on the changes being implemented in this NISPOM rule. Examples of those training materials and products range from online or in person training, job aids and web tools. DoD provides NISP training materials to the largest population, to include USG agencies and U.S. cleared legal entities, and estimates the time impact in year one is 1,128 hours for each of six individuals to update all the training materials with 564 hours in year two and 282 hours each year for maintenance of those materials in year 3 through year 20. The labor rate for those 6 personnel is estimated to be a GS13 step 5. These assumptions imply costs of \$0.67 million in year one; \$0.34 million in year 2; and \$0.17 million in each year 3 through 20. C. Total Costs/Cost Savings In summary the estimated public and USG costs/cost savings are (1) present value costs of \$150.26 million and annualized costs of \$10.52 million for the public; and, (2) present value cost of \$10.82 million and annualized costs of \$0.76 million for the USG. Throughout, labor rates are adjusted upward by 100% to account for overhead and benefits. Benefits Following the September 2013 Navy Yard shooting, the President directed the Office of Management and Budget (OMB) to lead a review of suitability and security clearance procedures for Federal employees and contractors (see

Back to Citation 368. · See ·HIPAA and Cybersecurity Authentication,· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (June 2023), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-june-2023/index.html> . Back to Citation 369. Id. (citing ·Implementing Phishing-Resistant MFA,· Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security (Oct. 2022), <https://www.cisa.gov/sites/default/files/publications/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf>); NIST also has issued draft defined characteristics for phishing-resistant authenticators. See David Temoshok, et al., ·Digital Identity Guidelines,· NIST Special Publication 800-63-4 2pd (Second Public Draft), National Institute of Standards and Technology, U.S. Department of Commerce, p. 36 (Aug. 21, 2024), <https://csrc.nist.gov/pubs/sp/800/63/4/2pd> . Back to Citation 370. · See proposed 45 CFR 164.312(f)(2)(ii) . Back to Citation 371. See ·HIPAA and Cybersecurity Authentication,· supra note 368 (citing David Temoshok, et al., ·Digital Identity Guidelines,· NIST Special Publication 800-63-4 (Initial Public Draft), National Institute of Standards and Technology, U.S. Department of Commerce, p. 17 (Dec. 2022), <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63-4.ipd.pdf>). Back to Citation 372. ·NIST defines ·token· as ·a portable, user-controlled, physical device (e.g., smart card or memory stick) used to store cryptographic information and possibly also perform cryptographic functions.· See NIST definition of ·token,· Glossary, Computer Security Resource Center, National Institute of Standards and Technology, U.S. Department of Commerce (citing Elaine Barker, et al., ·Recommendation for Key Management: Part 2·Best Practices for Key Management Organizations,· NIST Special Publication 800-57, Part 2, Revision 1, National Institute of Standards and Technology, U.S. Department of Commerce (May 2019)), <https://csrc.nist.gov/glossary/term/token#:~:text=NIST%20SP%20800%2D63%2D3%20under%20Token,possibly%20also%20perform%20cryptographic%20functions> . Back to Citation 373. ·Letter from NCVHS Chair Jacki Monson (2022), supra note 123, p. 7. Back to Citation 374. · See ·Digital Identity Guidelines: Authentication and Lifecycle Management,· NIST Special Publication 800-63B, National Institute of Standard and Technology, section 5.3.3, Use of Biometrics, (Oct. 16, 2023), <https://pages.nist.gov/800-63-3/sp800-63b.html#sec5> . We recognize that some of the example characteristics may not satisfy today's standards; however, the Department anticipates that they may in the future and proposes that they be included as examples such that regulated entities will be permitted to use them when the relevant standards are updated to allow for such use. Back to Citation 375. 45 CFR 164.304 (definition of ·Password·). Back to Citation 376. · See 45 CFR 164.304

(g) Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States that is within the exclusive jurisdiction of the U.S. Department of Agriculture (USDA) under the Federal Meat Inspection Act (21 U.S.C. 601 et seq.), the Poultry Products Inspection Act (21 U.S.C. 451 et seq.), or the Egg Products Inspection Act (21 U.S.C. 1031 et seq.) are excluded from all of the requirements in this subpart with respect to that food while it is under the exclusive jurisdiction of USDA. (h) Foreign persons, except for foreign persons who transport food in the United States, are excluded from all of the requirements of this subpart. (i) Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food are subject to §§ 1.361 and 1.363 with respect to its packaging (the outer packaging of food that bears the label and does not contact the food). All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import packaging are excluded from all of the requirements of this subpart. (j) Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food contact substances other than the finished container that directly contacts food are excluded from all of the requirements of this subpart, except §§ 1.361 and 1.363. (k) Persons who place food directly in contact with its finished container are subject to all of the requirements of this subpart as to the finished container that directly contacts that food. All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that directly contacts the food are excluded from the requirements of this subpart as to the finished container, except §§ 1.361 and 1.363. (l) Nonprofit food establishments are excluded from all of the requirements in this subpart, except §§ 1.361 and 1.363. (m) Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food for personal consumption are excluded from all of the requirements of this subpart. (n) Persons who receive or hold food on behalf of specific individual consumers and who are not also parties to the transaction and who are not in the business of distributing food are excluded from all of the requirements of this subpart.

§ 1.328 What definitions apply to this subpart? The definitions of terms in section 201 of the Federal Food, Drug, and Cosmetic Act (the act) (21 U.S.C. 321) apply to such terms when used in this subpart. In addition, for the purposes of this subpart: Act means the Federal Food, Drug, and Cosmetic Act. Farm means a facility in one general physical location devoted to the growing and harvesting of crops, the raising of animals (including seafood), or both. Washing, trimming of outer leaves, and cooling produce are considered part of harvesting. The term ·farm· includes:

A Registered Provider Organization (RPO) and a C3PAO serve different roles in the CMMC ecosystem:

****RPO (Registered Provider Organization)**:** - Provides consulting and preparation services - Helps organizations implement NIST SP 800-171 controls - Assists with SSP development, gap analysis, and remediation - Cannot conduct official CMMC certification assessments - May employ Registered Practitioners (RPs)

****C3PAO (Third-Party Assessment Organization)**:** - Conducts official CMMC Level 2 certification assessments - Cannot provide consulting services to the same organization they assess (conflict of interest) - Employs Certified CMMC Assessors (CCAs) - Assessment results submitted to Cyber AB for certification

Organizations typically engage an RPO first for preparation, then a separate C3PAO for the assessment.

(2) If the title of the specific official is unknown, such as for a local system, specify the local commander or office head as the systems manager. (3) For geographically separated or organizationally decentralized activities for which individuals may deal directly with officials at each location in exercising their rights, list the position or duty title of each category of officials responsible for the system or a segment thereof. (4) Do not include business or duty addresses if they are listed in the Component address directory. (l) Notification Procedures. (1) Describe how an individual may determine if there are records pertaining to him or her in the system. The procedural rules may be cited, but include a brief procedural description of the needed data. Provide sufficient information in the notice to allow an individual to exercise his or her rights without referral to the formal rules. (2) As a minimum, the caption shall include: (i) The official title (normally the system manager) and official address to which the request is to be directed. (ii) The specific information required to determine if there is a record of the individual in the system. (iii) Identification of the offices through which the individual may obtain notification; and (iv) A description of any proof of identity required. (see § 310.17(c)). (3) When appropriate, the individual may be referred to a Component official who shall provide this information to him or her. (m) Record Access Procedures. (1) Describe how an individual can gain access to the records pertaining to him or her in the system. The procedural rules may be cited, but include a brief procedural description of the needed data. Provide sufficient information in the notice to allow an individual to exercise his or her rights without referral to the formal rules.

(2) As a minimum, the caption shall include: (i) The official title (normally the system manager) and official address to which the request is to be directed. (ii) A description of any proof of identity required. (see §310.17(c)). (iii) When appropriate, the individual may be referred to a Component official who shall provide the records to him or her. (n) Contesting Record Procedures. (1) Describe how an individual may contest the content of a record pertaining to him or her in the system. (2) The detailed procedures for contesting a record need not be identified if the Component procedural rules are readily available to the public. (For example, The Office of the Secretary of Defense rules for contesting contents are contained in 32 CFR 311 .) All Component procedural rules are set forth at a Departmental public Web site (<http://www.defenselink.mil/privacy/cfr-rules.html>). (3) The individual may also be referred to the system manager to determine these procedures. (o) Record Source Categories. (1) Describe where (the individual, other Component documentation, other Federal agencies, etc) the information contained in the system was obtained.

CIS Control 17 Incident Response Management Establish a program to develop and maintain an incident response capability (e.g., policies, plans, procedures, defined roles, training, and communications) to prepare, detect, and quickly respond to an attack. A comprehensive cybersecurity program includes protections, detections, response, and recovery capabilities. Often, the final two get overlooked in immature enterprises, or the response technique to compromised systems is just to re-image them to original state, and move on. The primary goal of incident response is to identify threats on the enterprise, respond to them before they can spread, and remediate them before they can cause harm. Without understanding the full scope of an incident, how it happened, and what can be done to prevent it from happening again, defenders will just be in a perpetual whack-a-mole pattern. We cannot expect our protections to be effective 100% of the time. When an incident occurs, if an enterprise does not have a documented plan even with good people it is almost impossible to know the right investigative procedures, reporting, data collection, management responsibility, legal protocols, and communications strategy that will allow the enterprise to successfully understand, manage, and recover. Along with detection, containment, and eradication, communication to stakeholders is key. If we are to reduce the probability of material impact due to a cyber event, the enterprise's leadership must know what potential impact there could be, so that they can help prioritize remediation or restoration decisions that best support the enterprise. These business decisions could be based on regulatory compliance, disclosure rules, service-level agreements with partners or customers, revenue, or mission impacts. Dwell time from when an attack happens to when it is identified can be days, weeks, or months. The longer the attacker is in the enterprise's infrastructure, the more embedded they become and they will develop more ways to maintain persistent access for when they are eventually discovered. With the rise of ransomware, which is a stable moneymaker for attackers, this dwell time is critical, especially with modern tactics of stealing data before encrypting it for ransom.

AT.L2-3.2.2 Role-Based Training CMMC Assessment Guide Level 2 | Version 2.13 68 AT.L2-3.2.2
 ROLE-BASED TRAINING Ensure that personnel are trained to carry out their assigned information security-related duties and responsibilities. ASSESSMENT OBJECTIVES [NIST SP 800-171A]58 Determine if: [a] information security-related duties, roles, and responsibilities are defined; [b] information security-related duties, roles, and responsibilities are assigned to designated personnel; and [c] personnel are adequately trained to carry out their assigned information security-related duties, roles, and responsibilities. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]58 Examine [SELECT FROM: Security awareness and training policy; procedures addressing security training implementation; codes of federal regulations; security training curriculum; security training materials; system security plan; training records; other relevant documents or records]. Interview [SELECT FROM: Personnel with responsibilities for role-based security training; personnel with assigned system security roles and responsibilities; personnel with responsibilities for security awareness training; personnel with information security responsibilities; personnel representing the general system user community]. Test [SELECT FROM: Mechanisms managing role-based security training; mechanisms managing security awareness training]. DISCUSSION [NIST SP 800-171 REV. 2]59 Organizations determine the content and frequency of security training based on the assigned duties, roles, and responsibilities of individuals and the security requirements of organizations and the systems to which personnel have authorized access. In addition, organizations provide system developers, enterprise architects, security architects, acquisition/procurement officials, software developers, system developers, systems integrators, system/network administrators, personnel conducting configuration management and auditing activities, personnel performing independent verification and 58 NIST SP 800-171A, pp. 19-20. 59

A TCP approved by the CSA will be developed and implemented by those entities cleared under a VT, PA, SSA and SCA and when otherwise deemed appropriate by the CSA. The TCP will prescribe all security measures determined necessary to reasonably prevent the possibility of access by non-U.S. citizen employees and visitors to information for which they are not authorized. The TCP will also prescribe measures designed to assure that access by non-U.S. citizens is strictly limited to only that specific information for which appropriate USG disclosure authorization has been obtained, e.g., an approved export license or technical assistance agreement. Unique badging, escort, segregated work area, security indoctrination schemes, and other measures will be included, as appropriate. (2) Electronic communications plan (ECP). The contractor will develop and implement an ECP, subject to CSA approval, tailored to the contractor's operations to verify that electronic controls are in place for clear technical and logical separation of electronic communications and networks between the contractor, the foreign interest, and its affiliates. The purpose is to prevent the unauthorized disclosure of classified information to the foreign parent or its affiliates. The contractor will include in the ECP a detailed network description and configuration diagram that clearly delineates which networks will be shared and which will be protected from access by the foreign parent or its affiliates. The network description will address firewalls, remote administration, monitoring, maintenance, and separate email servers, as appropriate. (3) Affiliated operations plan. There may be circumstances when the parties to a transaction propose in the FOCI action plan that the U.S. contractor provides certain services for the foreign interest or enters into arrangements with the foreign interest, or the foreign interest provides services for or enters into arrangements with the U.S. contractor. In such circumstances, the contractor will document a plan, subject to CSA approval, outlining the entity's consolidated policies and procedures regarding the control of affiliated operations, regardless of whether such endeavors are administrative, operational, or commercial, performed directly or through third-party service providers, within the entity, or among any of the entity's controlled entities, or the foreign interest and its affiliates. (4) Facilities location plan. When a contractor is potentially collocated with or in close proximity to its foreign parent or an affiliate, the contractor will prepare a facilities location plan to assist the CSA in determining if the contractor is collocated or if the close proximity can be allowed under the FOCI mitigation plan. A U.S. entity generally cannot be collocated with the foreign parent or affiliate, i.e., at the same address or in the same location. (i) Annual review and certification. (1) Annual review.

3.2.2 | Attribute Accuracy ... 3.2.2 Attribute Accuracy Given the broad spectrum of entities that will interoperate with each other, synonyms of attribute definitions are inevitable. 3.2.2, focuses on the semantic accuracy of attribute values.

Control AM-6: ed in a single authorization boundary to ensure accountability. For systems processing PII, the privacy and security programs collaborate to develop a common understanding of authorization boundaries. To conduct effective risk assessments and select appropriate controls, privacy and security programs provide a clear and consistent understanding of what constitutes the authorization boundary. Understanding the authorization boundary and what will occur beyond it may influence controls selected and how they are implemented. For example, if a function of the system includes sharing PII externally, robust encryption controls may be selected for PII transmitted from the system. Similarly, for systems either partially or wholly managed, maintained, or operated by external providers, an agreement clearly describing authorization boundaries ensures accountability. Privacy and security programs collaborate with providers to develop a common understanding of authorization boundaries. Formal agreements with external providers (e.g. contracts) may be used to delineate what constitutes authorization boundaries. Understanding such boundaries facilitates the selection of appropriate controls to manage supply chain risk. References: [SP 800-18]; [SP 800-39] (System Level); [SP 800-47]; [SP 800-64]; [SP 800-160 v1] (System Requirements Definition Process); [NIST CSF] (Core [Identify Function]). ## INFORMATION TYPES TASK P-12 Identify the types of information to be processed, stored, and transmitted by the system. Potential Inputs: System design documentation; assets to be protected; mission/business process information; system design documentation. Expected Outputs: A list of information types for the system. Primary Responsibility: System Owner; Information Owner or Steward. Supporting Role: Mission or Business Owner; System Security Officer; System Privacy Officer. 66 System Development Life Cycle Phase: New - Initiation (concept/requirements definition).

In addition, the CMMC Program relies upon free market influences of supply and demand to propel implementation. Specifically, the Department does not control which defense contractors aspire to compete for which business opportunities, nor does it control access to the assessment services offered by C3PAOs. OSAs may elect to complete a self-assessment or pursue a certification assessment at any time after issuance of the rule, in an effort to distinguish themselves as competitive for efforts that require an ability to adequately protect CUI. For that reason, the number of CMMC assessments for unique entities per level per year may vary significantly from the assumptions used in generating the cost estimate. The estimates represent the best estimates at this time based on internal expertise and public feedback. DoD utilized historical metrics gathered for the CMMC 1.0 Program and subject matter expertise from Defense Pricing and Contracting (DPC) and DCMA DIBCAC to estimate the number of entities by type and by assessment level for this analysis. The following (printed page 89085) table summarizes the estimated profile used in this analysis. DoD is planning for a phased roll-out of each assessment level across 7 years with the entity numbers reaching a maximum by Year 4 as shown in the tables. The target of Year 4 was selected based on the projected capacity of the CMMC Ecosystem to grow to efficiently support the entities in the pipeline. For modeling efficiency, a similar roll-out is assumed regardless of entity size or assessment level. It is assumed that by year 7 the maximum number of entities is reached. Beyond year 7, the number of entities entering and exiting are expected to net to zero. The following tables reflect the number of new entities in each year and for each level. (printed page 89086) Public Costs Summary of Impacted Awardee Entities According to data available in the Electronic Data Access system for fiscal years (FYs) 2019, 2020, and 2021, DoD awards an average of 1,366,262 contracts and orders per year that contain DFARS clause 252.204-7012, to 31,338 unique awardees, of which 683,718 awards (50%) are made to 23,475 small entities (75%). [29] Public Cost Analysis The following is a summary of the estimated Public costs CMMC 2.0 for other than small [30] entities, per assessment of a contractor information system, at the required periodicity for each CMMC level. The following is a summary of the estimated Public costs CMMC 2.0 for Small Entities, per assessment of each contractor information system, estimated at one per entity, at the required periodicity for each CMMC level. (printed page 89087) The total estimated Public (large and small entities) costs associated with this rule, calculated for a 20-year horizon in 2023 dollars at a 7 percent and 3 percent discount rate, per OMB guidance, is provided as follows: Assumptions In estimating the Public costs, DoD considered applicable nonrecurring engineering costs, recurring engineering costs,

. We adjusted the contributions by large and very small facilities to traceback performance to reflect the substantially different quantities of food each facility size is responsible for. While the number of very small facilities accounts for a large fraction of the total number of facilities, the quantity of food for which these facilities are responsible is relatively small. Consequently, estimates of the contributions to traceback performance should reflect the lower likelihoods of investigative visits at very small businesses. For options that differentiate between coverage by facility size, we used estimates of the quantities of food passing through very small establishments and the quantities of food passing through all other sized establishments to scale each sector's contribution to traceback performance. In this way we were able to estimate the contribution by very small size establishments and other size establishments to traceback performance for each sector. We used U.S. Census data (Ref. 17) to estimate the percentage of the total number of food establishments that are very small, as well as their revenues, by sector and report them in the chart below. The fraction of the total number of facilities that are very small ranges from an estimated 73 percent of convenience outlets to 90 percent of transporters. In contrast, the percentage of total convenience store revenues from very small facilities is an estimated 18 percent, while very small transporters are responsible for an estimated 16 percent of total revenues from that sector. Table 11. The percentage of very small food establishments that make up each sector and the percentage of the total sector's food for which they are responsible

Sector	% of Establishments That Are Very Small	% of Food Sector Revenue From Very Small Establishments
Manufacturers	77	15
Wholesalers	81	14
Transporters	90	16
Grocery outlets	88	18
Convenience outlets	73	18
Importers	82	14
Mixed-type facilities	82	15

Source: U.S. Census, 1997 Economic Census. In addition to a lower probability of an investigative visit at very small compared with other size facilities, records quality or records access times might also be different for very small and other size facilities. However, conversations with FDA investigative personnel revealed that there are no differences in records quality or records access times across business sizes. Consequently, we estimate the duration of an investigative visit to be the same for very small and other size businesses. 12. Estimating the

Benefits When Selected Sectors Are Excluded

(A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (29) System identifier and name. A0600-20 DCSG-1, Sexual Assault (SADMS) and Sexual Harassment (SHARP) Program Records. (i) Exemption. This system of records is a compilation of information from other Department of Defense/Army systems of records. To the extent that copies of exempt records from those other systems of records are entered into this system of records, the Army G-1 hereby claims the same exemptions for the records from those other systems. (ii) Authority. 5 U.S.C. 552a(j)(2) , and (k)(1) through (k)(7) . (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a

.implement and .deploy, we propose to replace the requirement for a regulated entity to implement procedures with a requirement to deploy technical controls. Also, consistent with our proposals to clarify that a regulated entity's obligations to ensure the confidentiality, integrity, and availability extend to all of its relevant electronic information systems, we propose to clarify that the regulated entity is to deploy technical controls to verify that a person seeking access to the regulated entity's relevant electronic information systems is the one claimed. The Department also proposes to modify the existing standard to clarify that a regulated entity would be required to deploy technical controls to verify that a technology asset seeking access to the regulated entity's relevant electronic information systems is the one claimed. Thus, the proposed standard for authentication would require a regulated entity to deploy technical controls to verify that a person or technology asset seeking access to ePHI and/or the regulated entity's relevant electronic information systems is, in fact, the person or technology asset that the person or asset claims to be. We also propose to remove the reference to an entity because entity is included within the definition of person. The Department proposes four implementation specifications under this standard. Consistent with NCVHS' recommendation to eliminate the use of default passwords, the proposed implementation specification for information access management policies at proposed 45 CFR 164.312(f)(2)(i) would require a regulated entity to deploy technical controls in accordance with its information access management policies and procedures, including technical controls that require users to adopt unique passwords. [773] Among other things, this proposal would ensure that regulated entities change default passwords. Such unique passwords would be required to be consistent with current recommendations of authoritative sources. The Department does not propose to define authoritative sources and defers to best practices for setting and maintaining passwords of sufficient strength to ensure the confidentiality, integrity, and availability of ePHI. Under this proposal, a regulated entity would need to require its workforce members to change any default passwords to unique passwords that are consistent with current authoritative source recommendations for unique passwords, as well as prevent the sharing of passwords among workforce members. Default passwords, typically factory-set passwords, may be discovered in common product documentation and used by attackers to gain access to relevant electronic information systems. [774] Thus, the Department believes that it is crucial for the security of ePHI that a regulated entity eliminate the use of default passwords.

. Privacy Impact Assessments are required for all information systems and electronic collections

that collect, maintain, use, or disseminate personally identifiable information about members of the public (this includes contractors and family members), under Public Law 107-347, Section 208 of the E-Government Act of 2002. DoD Instruction 5400.16, entitled Department of Defense Privacy Impact Assessment (PIA) (Available at <http://www.dtic.mil/whs/directives/corres/pdf/540016p.pdf>), provides additional requirements for PIAs, including a requirement to write a PIA on any information systems or electronic collection of PII on Federal personnel. Protected Health Information (PHI). Any information about health status, provision of health care, or payment for health care that can be linked to a specific individual. Record. Any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, the individual's his education, financial transactions, medical history, and criminal or employment history and that contains his name, or the identifying number, symbol, or other identifying particular assigned to the individual, such as a finger or voice print or a photograph (As defined by 5 U.S.C. 552a). Relevance. Limitation to only those elements of information that clearly bear of the determination(s) for which the records are intended. Routine Use. The disclosure of a record outside the DoD for a use that is compatible with the purpose for which the information was collected and maintained by the DoD. The routine use must be included in the published system notice for the SOR involved. The DoD Blanket Routine Uses, found in 32 CFR part 310, Appendix C are applicable to all SORNs published by DoD. System Manager. The official who is responsible for managing a SOR, including policies and procedures to operate and safeguard it. Local System Managers operate record systems or are responsible for the records that are maintained in decentralized locations but are covered by a SORN published by another DoD activity or a Government-Wide SORN. System of Records (SOR). A group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual. System of Records Notice (SORN). The official public notice published in the FR of the existence and content of the SOR. As required by 5 U.S.C. 552a and 32 CFR part 310, Appendix E. The notice shall include: (1) The name and location of the system, (2) The categories of individuals on whom records are maintained in the system, (3) The categories of records maintained in the system, (4) Each routine use of the records contained in the system, including the categories of users and the purpose of such use, (5) The policies and practices of the agency regarding storage, retrievability, access controls, retention, and disposal of the records,

CMVP Validation Authority Updates to ISO/IEC 24759 CMVP Validation Authority Updates to ISO/IEC 24759 Calis A (2023) Cryptographic Module Validation Program (CMVP)-Approved Sensitive Security Parameter Generation and Establishment Methods: CMVP Validation Authority Updates to ISO/IEC 24759. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-140Dr2. <https://doi.org/10.6028/NIST.SP.800-140Dr2>

ng program. CSD also invites public and private organizations to submit their information security practices for consideration to be included in the list of practices maintained on the Web site. Policies and procedures may be submitted to NIST in any area of information security, including accreditation, audit trails, authorization of processing, budget planning and justification, certification, contingency planning, data integrity, disaster planning, documentation, hardware and system maintenance, identification and authentication, incident handling and response, life cycle, network security, personnel security, physical and environmental protection, production input/output controls, security policy, program management, review of security controls, risk management, security awareness training and education (to include specific course and awareness materials) and security planning. Current participants include Computer Associates, the Internet Security Task Force, Microsoft, the SANS Institute, the Carnegie Mellon University CERT Coordination Center, the American Bankers Association, Ars Technica and EDUCAUSE. This area added twelve practices in the past year bringing the total number of listings to twenty.

for submitting electronic comments. Attachments should be in Microsoft Word or Portable Document Format (PDF). Regular, Express, or Overnight Mail: You may mail written comments to the following address only: U.S. Department of Health and Human Services, Office for Civil Rights, Attention: HIPAA Security Rule NPRM, Hubert H. Humphrey Building, Room 509F, 200 Independence Avenue SW, Washington, DC 20201. Please allow sufficient time for mailed comments to be timely received in the event of delivery or security delays. Please note that comments submitted by fax or email and those submitted after the comment period will not be accepted. Inspection of Public Comments: All comments received by the accepted methods and due date specified above may be posted without change

to content to <https://www.regulations.gov> , which may include personal information provided about the commenter, and such posting may occur after the closing of the comment period. However, the Department may redact certain non-substantive content from comments or attachments to comments before posting, including: threats, hate speech, profanity, sensitive health information, graphic images, promotional materials, copyrighted materials, or individually identifiable information about a third-party individual other than the commenter. In addition, comments or material designated as confidential or not to be disclosed to the public will not be accepted. Comments may be redacted or rejected as described above without notice to the commenter, and the Department will not consider in rulemaking any redacted or rejected content that would not be made available to the public as part of the administrative record. Docket: For complete access to background documents, the plain-language summary of the proposed rule of not more than 100 words in length required by the Providing Accountability Through Transparency Act of 2023, or posted comments, go to <https://www.regulations.gov> and search for Docket ID number HHS-OCR-0945-AA22. Tribal consultation meeting: To participate in the Tribal consultation meeting, you must register in advance at <https://hhs.gov.zoomgov.com/join/registration/vJltdOyhrjgoHxJWMDxozrxT98yXyCO3lks> . FOR FURTHER INFORMATION CONTACT: Marissa Gordon-Nguyen at (202) 240-3110 or (800) 537-7697 (TDD), or by email at OCRPrivacy@hhs.gov . SUPPLEMENTARY INFORMATION:

CIS Safeguard 13.7 · Deploy a Host-Based Intrusion Prevention Solution Deploy a host-based intrusion prevention solution on enterprise assets, where appropriate and/or supported. Example implementations include use of an Endpoint Detection and Response (EDR) client or host-based IPS agent. Implementation Groups: 3 Asset Type: devices Security Function: protect Parent Control: Network Monitoring and Defense

(14) Maintain appropriate administrative technical and physical safeguards to ensure records are protected from unauthorized alteration or disclosure. (b) Safeguard personal information . (1) Privacy Act data will be afforded reasonable safeguards to prevent inadvertent or unauthorized disclosure of records during processing, storage, transmission, and disposal. (2) Personal information should never be placed on shared drives that are accessed by groups of individuals unless each person has an ·official need to know· the information in the performance of official duties. (printed page 46055) (3) Safeguarding methods must strike a balance between the sensitivity of the data, need for accuracy and reliability for operations, general security of the area, and cost of the safeguards. In some situations, a password may be enough protection for an automated system with a log-on protocol. For additional guidance on safeguarding personal information in automated records see AR 380-67, The Department of the Army Personnel Security Program. (c) Conveying privacy protected data electronically via e-mail and the World Wide Web. (1) Unencrypted electronic transmission of privacy protected data makes the Army vulnerable to information interception which can cause serious harm to the individual and the accomplishment of the Army's mission. (2) The Privacy Act requires that appropriate technical safeguards be established, based on the media (e.g. , paper, electronic) involved, to ensure the security of the records and to prevent compromise or misuse during transfer. (3) Privacy Web sites and hosted systems with privacy-protected data will employ secure sockets layers (SSL) and Public Key Infrastructure (PKI) encryption certificates or other DoD-approved commercially available certificates for server authentication and client/server authentication. Individuals who transmit data containing personally identifiable information over e-mail will employ PKI or other DoD-approved certificates. (4) When sending Privacy Act protected information within the Army using encrypted or dedicated lines, ensure that: (i) There is an ·official need to know· for each addressee (including ·cc· addressees); and (ii) The Privacy Act protected information is marked For Official Use Only (FOUO) to inform the recipient of limitations on further dissemination. For example, add FOUO to the beginning of an e-mail message, along with the following language: ·This contains FOR OFFICIAL USE ONLY (FOUO) information which is protected under the Privacy Act of 1974 and AR 340-21, The Army Privacy Program. Do not further disseminate this information without the permission of the sender.· (iii) Do not indiscriminately apply this statement. Use it only in situations when actually transmitting protected Privacy Act information. (iv) For additional information about marking documents ·FOUO· review AR 25-55, Chapter IV.

The CMMC proposed rule was published in the Federal Register on December 26, 2023, to initiate the mandatory 60-day public review and comment period for this rule and the supporting documents that ended on 26 February 2024. From the volume of comments received on the CMMC rule documents, from or concerning Small Businesses, the following significant issues were raised. 1. Cost. Some comments

identified that the proposed rule does not address how the CMMC Program will be funded, or how the costs of certification and compliance will be shared between the DoD and the contractors. This may raise questions about the affordability and sustainability of the CMMC program, especially for small businesses. Commenters suggested that the DoD conduct and publish a comprehensive cost assessment for each level of CMMC certification and explore ways to reduce the financial burden on the contractors, such as providing incentives, subsidies, loans, grants, tax credits or reimbursements. Several comments presented the opinion that the cost estimates in the preamble/rule did not adequately address all possible costs to become compliant with regulations and attain a certification i.e., ongoing Recurring Engineering and Non-Recurring Engineering costs. Others commented that the mandate to comply with requirements, attain verification of compliance, and the inability to recoup costs prior to completing compliance will be barriers to entry and will drive many small businesses out of the DoD market. Concern was also expressed regarding the cost of failing an assessment and not being able to recoup costs fast enough, through increased Overhead and G&A [General and Administrative] rates. Another concern was raised that IR&D [Independent Research and Development] spending will be negatively impacted due to the diversion of funds to Cybersecurity compliance. Some shared concerns about the potential for overmarking CUI data, that will drive a higher than necessary demand for CMMC certification and create an overburdened Ecosystem, thereby preventing timely certification and incentivizing price gouging by assessors. Several suggested that the Government regulate the prices for assessment services. Many commenters also suggested the DoD needed to find ways to reduce the financial burdens on small businesses through direct payment for compliance, tax incentives, increased profits, or increased flexibility to comply with requirements, i.e., by reducing requirements for small businesses or providing more time to comply after contract award. Commenters also felt the handling of CUI by small businesses was too difficult, and recommended prime contractors should be responsible for handling all CUI. If a small business needs CUI to execute its work, the prime or the Government should provide an environment for the small business to complete its work. DoD Response.

Organizations can employ full -device encryption or container -based encryption to protect the confidentiality of CUI on mobile devices and computing platforms . Container-based encryption provides a more fine-grained approach to the encryption of data and information including encrypting selected data structures such as files, records, or fields. FURTHER DISCUSSION Ensure CUI is encrypted on all mobile devices and mobile computing platforms that process, store, or transmit CUI including smartphones, tablets, and e-readers. 48 NIST SP 800-171A, p. 17. 49 NIST SP 800-171 Rev. 2, p. 15.

DMDC 15 DoD, Armed Services Military Accession Testing. (i) Exemption. Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service or military service may be exempt pursuant to 5 U.S.C. 552a(k)(6) , if the disclosure would compromise the objectivity or fairness of the test or examination process. Therefore, portions of the system of records may be exempt pursuant to 5 U.S.C. 552a(d) . (ii) Authority. 5 U.S.C. 552a(k)(6) . (iii) Reasons. (A) An exemption is required for those portions of the Skill Qualification Test system pertaining to individual item responses and scoring keys to preclude compromise of the test and to ensure fairness and objectivity of the evaluation system. (B) From subsection (d)(1) when access to those portions of the Skill Qualification Test records would reveal the individual item responses and scoring keys. Disclosure of the individual item responses and scoring keys will compromise the objectivity and fairness of the test as well as the validity of future tests resulting in the Department being unable to use the testing battery as an individual assessment tool. (17) System identifier and name. DMDC 11, Investigative Records Repository. (i) Exemption. (A) Investigative material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Records maintained in connection with providing protective services to the President and other individuals under 18 U.S.C. 3506 , may be exempt pursuant to 5 U.S.C. 552a(k)(3) . (C) Investigative material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (D) Any portion of this system that falls under the provisions of 5 U.S.C. 552a(k)(2) ,

(k)(3), or (k)(5) may be exempt from the following subsections of 5 U.S.C. 552(c)(3), (d), (e)(1), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2), (k)(3), or (k)(5). (iii) Reasons.

(a) The Office of the Department of Defense Chief Information Officer (DoD CIO) Office of the Deputy CIO for Cybersecurity (DoD CIO(CS)) provides oversight of the CMMC Program and is responsible for establishing CMMC assessment, accreditation, and training requirements as well as developing and updating CMMC Program policies and implementing guidance. The CMMC PMO is responsible for the granting and revocation of the validity status of the appropriate CMMC certification level, which officially resides within SPRS based on inputs from the OSA, C3PAO, and or DCMA DIBCAC. (b) The CMMC PMO is responsible for investigating and acting upon indications that an active CMMC Self-Assessment, described in §§ 170.15 and 170.16, or CMMC Certification Assessment, described in §§ 170.17 and 170.18, has been called into question. Indications that may trigger investigative evaluations include, but are not limited to, reports from the CMMC Accreditation Body, a C3PAO, or anyone knowledgeable of the security processes and activities of the OSA. Investigative evaluations include, but are not limited to, reviewing pertinent assessment information and exercising the right to require a DCMA DIBCAC assessment of the OSA, as provided for under the DFARS clauses 252.204-7012 and 252.204-7020 (48 CFR 252.204-7012 and 252.204-7020). (c) If the investigative results show that adherence to the provisions of this rule have not been achieved or maintained, the CMMC PMO may revoke the validity status of the appropriate existing CMMC Self-Assessment(s) or CMMC Final Certification Assessment(s). § 170.7 DCMA DIBCAC. (a) In support of the CMMC Program, DoD intends that the DCMA DIBCAC assessors performing Level 3 assessments will: (1) Complete CMMC Level 2 and Level 3 training. (2) Conduct CMMC Level 3 Certification Assessments and upload assessment results into the CMMC instantiation of eMASS. (3) Issue CMMC Level 3 Certification Assessment certificates. (4) Conduct CMMC Level 2 assessments of the Accreditation Body and prospective C3PAOs information systems that process, store, and/or transmit CUI. (5) Create and maintain a process for assessors to collect the list of assessment artifacts to include artifact names, their return values of the hashing algorithm, the hashing algorithm used, and upload that data into the CMMC instantiation of eMASS. (6) As authorized and in accordance with all legal requirements, enter and track, OSC appeals and updated results arising from CMMC Level 3 Certification Assessment activities into the CMMC instantiation of eMASS. (7) Retain all records in accordance with DCMA-MAN 4501-04. (b) [Reserved]. Subpart C-CMMC Assessment and Certification Ecosystem § 170.8 Accreditation Body. (a) Roles and responsibilities.

Advanced Encryption Standard (AES) Subcategory: Cryptography In 2000, NIST announced the selection of the Rijndael block cipher family as the winner of the Advanced Encryption Standard (AES) competition. Block ciphers are the foundation for many cryptographic services, especially those that provide assurance of the confidentiality of data.

One commenter recommended administrative edits to identify CMMC levels at a particular place in the pre-amble description of the program. The preamble is not part of the official regulation. In addition to background and overview information about the proposed or final rule, the preamble includes responses to all comments received during the public comment period on the proposed rule. The certification requirements are in subpart D, §§ 170.15 through 170.18. c. Alternate Implementation Timelines Comment: Several commenters suggested that DoD abandon CMMC requirements in favor of simply continuing to rely upon self-assessments, or else allowing contractors to comply with DFARS clause 252.204-7012 requirements absent any assessment (self-conducted or third-party). Of those recommending self-assessment, two commenters limited the suggestion only to companies that self-certified as small businesses and one further recommended that DoD pay for certification assessment of all small businesses. One such commenter based their opinion on an interpretation that text in NIST SP 800-171 R2 identifies the requirements as a model for self-assessment. Another commenter made no suggestion to change assessment requirements, other than to implement them post-award, rather than pre-award. One comment expressed doubt in the ability of the ecosystem to scale sufficiently to meet the demand for C3PAO assessments and assessor training. One commenter suggested the rule be revised to eliminate POA&Ms but expand the period during which deficiencies can be reassessed from within 10 days of initial assessment to 60 days for those prospective contractors. Another commenter suggested varying timelines for POA&Ms based on a variety of criteria, including how many DoD contracts are held. Response: The DoD declined to accept the risk associated with implementing CMMC solely as a post-award requirement. When contracts require contractors to process, store, or transmit CUI, DoD requires that they be compliant with DFARS

clause 252.204-7012 and competent to adequately safeguard CUI from the beginning of the period of performance. DoD declines the recommendation to require primes to assume the cost of CMMC for their subcontractors. Arrangements between contractors and subcontractors are negotiated directly between those parties. The DoD does not accept the recommendation to eliminate or change the criteria for POA&Ms or the timeline allowed to remediate open POA&M items. The 180-day period allowed for POA&Ms and the determination of which weighted practices can be placed on a POA&M was a risk-based decision. The determination considers the relative risk DoD is willing to accept when a particular practice is not met and the amount of risk the DoD is willing to accept for those security practices that go ·NOT MET· for an extended period.

- The first column defines the capability. Note that Figure 1, which is located in Appendix A, indicates how the capability relates to the risk mitigation areas and challenges defined in NISTIR 8228, Considerations for Managing Internet of Things (IoT) Cybersecurity and Privacy Risks [3]. - The second column provides a numbered list of common elements of that capability-elements an organization seeking to implement the core baseline often (but not always) would use in order to achieve the capability. (Note: the elements are not intended to be comprehensive, nor are they in any particular order.) - The third column explains the rationale for needing the capability and its common elements to be included in the core baseline. - The last column lists IoT reference examples that indicate existing sources of IoT device cybersecurity guidance specifying a similar or related capability. Because the table only covers the basics of the capabilities, the references can be invaluable for understanding each capability in more detail and learning how to implement each capability in a reasonable manner.

There were no changes from the proposed rule as a result of the public comments received. There were minor editorial changes made to the proposed rule, see Section C below.

B. Analysis of Public Comments

1. Commercial and Government Entity (CAGE) Code Reporting Comment: Two respondents expressed concern regarding the use of ·Unique CAGE code·; stating that in some instances a facility will have multiple locations with the same CAGE codes. Clarification of the term ·unique· CAGE code was requested. Response: In accordance with the National Industrial Security Program Operating Manual (NISPOM) DoD 5220.22-M and FAR 52.204-16(g), each contractor and subcontractor location of performance listed on a DD Form 254 is required to have a unique CAGE code; and registration in the System for Award Management (SAM) is not required for contractor and subcontractor performance locations solely for the purposes of the DD Form 254. FAR 52.204-16, Commercial and Government Entity (CAGE) Code Reporting, as prescribed at FAR 4.1804(a), is amended to add paragraph (g) to require subcontractors requiring access to classified information under a contract to be identified with a CAGE code on the DD Form 254. Contractors shall ensure that a subcontractor requiring access to classified information provide its CAGE code with its name and location address or otherwise include it prominently in the proposal. In addition, each location of subcontractor performance must be listed on the DD Form 254 and is required to reflect a corresponding unique CAGE code for each listed location unless the work is being performed at a Government facility, in (printed page 40062) which case the agency location code shall be used. The CAGE code must be for that name and location address. The CAGE code is required prior to award. Each listed location must have a unique CAGE code classifying only a single location. Comment: Two respondents opposed the removal of the current CAGE code requirement and stressed the continued need to not increase risk of sharing classified information with an uncleared facility or one where the clearance is no longer active or authorized. Response: The rule does not decrease the security professional's ability to verify security clearance and safeguarding levels as directed by NISPOM via the National Industrial Security System (NISS). The rule will require electronic submission of the DD Form 254, Contract Security Classification Specification.

2. DD Form 254 Comment: Two respondents recommended submission of the DD Form 254 by company name with an ·option· to file by CAGE code and if possible link the form to the website for storage and potential reuse to avoid uploading as part of an application ·process· via the contractor's tools and processes for DD Form 254 submission. Response:

The CMMC Program validates implementation of DoD's required cyber protection standards for companies in the DIB. Furthermore, this rule benefits the efficient functioning of the economy and private markets for all sizes of companies, including the smallest, most vulnerable companies, by: (1) protecting DoD from the loss of FCI and CUI; (2) promoting improvements in cybersecurity and accountability across DoD supply chains; (3) promoting continued innovation by helping to prevent significant loss of revenue, benefits, and jobs to the companies involved in developing those

innovations for DoD; (4) promoting U.S. technical advantage and superiority; and (5) improving the safeguarding of competitive advantages and protections for proprietary information and capabilities through requirements flow-down throughout the defense contractor supply chain. (b) Costs A Regulatory Impact Analysis (RIA) that includes a detailed discussion and explanation about the assumptions and methodology used to estimate the cost of this regulatory action is available at www.regulations.gov (search for ·DoD-2023-OS-0063· click ·Open Docket· and view ·Supporting Documents·). The total estimated Public (large and small entities) and Government costs associated with this rule, calculated in over a 20-year horizon in 2023 dollars at a 7 percent discount rate and a 3 percent discount rate are provided as follows: The following shows the estimated number of small entities [54] anticipated to pursue compliance or certification, at each CMMC level, over a phased implementation. These estimates were generated based upon prior year procurement data. (printed page 89105) The following is a summary of the estimated public costs of CMMC for small entities, per assessment of each contractor information system, at the required periodicity for each CMMC level. The following estimates are Small Entity Public and Government costs for CMMC requirements calculated over a 20-year horizon in 2023 dollars at a 7 percent discount rate. (printed page 89106) (4) Small Business Entities Impacted This rule will impact small businesses that do business with the Department of Defense as a prime or subcontractor, except for contracts or orders that are exclusively for COTS items or valued at or below the micro-purchase threshold. According to the Federal Procurement Data System (FPDS) there is an annual average of 30,145 unique small business contractors in DoD: FY 2019 (31,189), FY 2020 (29,166), FY 2021 (27,427) and FY 2022 (32,798). Cost Assumptions and Analysis for CMMC 2.0 Complete details on CMMC requirements and associated costs, savings, and benefits of this rule are provided in the Regulatory Impact Analysis referenced in the Preamble. Key components of CMMC Program requirements are described in 32 CFR Subpart D . (a) Comparison to CMMC 1.0 Cost Analysis Public comment feedback on CMMC 1.0 indicated that cost estimates were too low. CMMC 2.0 cost estimates account for that feedback with the following improvements:

Access to equipment and information by DoD personnel. (i) The CDC will allow, upon request by DoD personnel, access by DoD personnel to additional equipment or information of the CDC that is necessary to conduct forensic analysis of reportable cyber incidents in addition to any analysis conducted by the CDC. (ii) The CDC is only required to provide DoD access to equipment or information to determine whether information created by or for DoD in connection with any DoD program was successfully exfiltrated from a CDC's network or information system, and what information was exfiltrated from the CDC's network or information system. (g) Reports to ISOO. (1) Contractors will report instances of redundant or duplicative security review and audit activity by the CSAs to the Director, ISOO, for resolution. (2) Contractors will report instances of CSAs duplicating processing to determine an entity's eligibility for access to classified information when there is an existing determination of an entity's eligibility for access to classified information by another CSA. §·117.9 Entity eligibility determination for access to classified information. (a) General. This section applies to all contractors with entity eligibility determinations, except as provided in §·117.22 for entity eligibility determinations for participation in the CCIPP under the cognizance of DHS. (1) Prior to the entity being granted an entity eligibility determination for access to classified information, the responsible CSA must have determined that: (i) The entity is eligible for access to classified information to meet a legitimate USG or foreign government need. (ii) Access is consistent with national security interests. (2) The CSA will provide guidance on processing entity eligibility determinations for entity access to classified information. (3) The determination of entity eligibility for access is separate from the determination of a classified (printed page 83326) information safeguarding capability (see §·117.15). (4) Neither the contractor nor its employees will be permitted access to classified information until the CSA has made an entity eligibility determination (e.g., issued an FCL). (5) The requirement for a favorable entity eligibility determination (also referred to in some instances as an FCL) for a prime contractor includes instances where all access to classified information will be limited to subcontractors. A prime contractor must have a favorable entity eligibility determination at the same or higher classification level as its subcontractors. (6) Contractors are eligible for storage of classified material in connection with a legitimate USG or foreign government requirement if they have a favorable entity eligibility determination and a classified information safeguarding capability approved by the CSA. (7) An entity eligibility determination is valid for access to classified information at the same or lower classification level.

(13) Disclosure to the Merit Systems Protection Board Routine Use. A record from a system of records maintained by a DOD component may be disclosed as a routine use to the Merit Systems Protection Board, including the Office of the Special Counsel for the purpose of litigation, including administrative procedures, appeals, special studies of the civil service and other merit systems, review of Office of Personnel Management or component rules and regulations, investigation of alleged or possible prohibited personnel practices, including administrative proceedings involving any individual subject of a DOD investigation, and such other functions, promulgated in 5 U.S.C. sections 1205 and 1206, or as may be authorized by law. (14) Counterintelligence Purposes Routine Use. A record from a system of records maintained by a DOD component may be disclosed as a routine use outside the DOD or the U.S. Government for the purpose of counterintelligence activities authorized by U.S. Law or Executive Order or for the purpose of enforcing laws, which protect the national security of the United States. Appendix E to Part 505-Litigation Status Sheet (a) Case Number: The number used by a DA activity for reference purposes; Requester; (b) Document Title or Description: Indicates the nature of the case, such as ·Denial of access·, ·Refusal to amend·, ·Incorrect records·, or other violations of the Act (specify); (c) Litigation: Date complaint filed, Court, and Case File Number; (d) Defendants: DOD component and individual; (e) Remarks: Brief explanation of what the case is about; (f) Court action: Court's finding and disciplinary action (if applicable); and (g) Appeal (If applicable): Date complaint filed, court, case File Number, court's finding, disciplinary action (if applicable). Appendix F to Part 505-Example of a System of Records Notice (a) Additional information and guidance on Privacy Act system of records notices are found in DA PAM 25-51. The following elements comprise a Privacy Act system of records notice for publication in the Federal Register: (b) System Identifier: A0025-55 AHRC·DA FOIA/P Office assigns the notice number, for example, A0025-55, where ·A· indicates ·Army·, the next number represents the publication series number related to the subject matter, and the final letter group shows the system manager's command. In this case, it would be U.S. Army Human Resources Command. (c) System Name: Use a short, specific, plain language title that identifies the system's general purpose (limited to 55 characters). (d) System Location: Specify the address of the primary system and any decentralized elements, including automated data systems with a central computer facility and input or output terminals at separate locations. Use street address, 2-letter state abbreviations and 9-digit ZIP Codes. Spell out office names. Do not use office symbols.

The Department would expect this proposed exception to be applicable for a limited period of time and only when encryption is infeasible. As noted above, the proposed exception to encryption would narrowly apply only when a regulated entity's relevant electronic information system is adversely affected by the emergency or other occurrence. The proposed exception would no longer be applicable at such time encryption becomes feasible, regardless of whether the emergency or other occurrence continues. The fourth proposed set of exceptions at proposed 45 CFR 164.312(b)(3)(iv) would be for ePHI that is created, received, maintained, or transmitted by a medical device (i.e., a ·device· within the meaning of section 201(h) of the Federal Food, Drug, and Cosmetic Act, 21 U.S.C. 321(h)) that is authorized by the FDA for marketing. We propose three separate exceptions for devices that are authorized by the FDA for marketing pursuant to: a submission received before March 29, 2023; a submission received on or after March 29, 2023, where the device is no longer supported by its manufacturer; or a submission received on or after March 29, 2023, where the device is supported by its manufacturer. Where a device has been authorized by the FDA for marketing pursuant to a submission received before March 29, 2023, we propose that the exception at proposed 45 CFR 164.312(b)(3)(iv)(A) would be available only where the regulated entity deploys in a timely manner any updates or patches required or recommended by the manufacturer of the device. We also propose a similar exception at proposed 45 CFR 164.312(b)(3)(iv)(B) for devices authorized by the FDA for marketing pursuant to a submission received on or (printed page 970) after March 29, 2023, where the device is no longer supported by its manufacturer, provided that the regulated entity has deployed any updates or patches required or recommended by the manufacturer. We recognize that, to comply with this proposal, some regulated entities may incur costs for replacing legacy medical devices (i.e., medical devices that cannot be reasonably protected against current cybersecurity threats). [742] We also recognize that legacy devices can pose significant risks to the confidentiality, integrity, and availability of ePHI. [743]

(Comment 135) One comment states that records should be retained for 2 years from the date they are created, and not for 2 years from the date of shipment of the product. The comment points out that wine may be shipped several years after it has been manufactured, and that establishing the timeframe from the date of shipment of the product would be an unwarranted burden. One comment

suggests that the minimum record retention periods should be stated as time from the date of production, e.g., a minimum of 2 years after the date of production of the food, except perishables, and a minimum of 1 year after the date of production for perishables. (Response) FDA does not agree with the comment's suggestion, as this will not ensure that FDA has access to the requisite records at the time of a traceback investigation. Often, a traceback begins after consumers become sickened or die. In the comment's example, if the wine was adulterated and presented a threat of serious adverse health consequences or death to humans, FDA may not know this until the wine has been consumed, i.e., after the product was released by the manufacturer into commerce and consumers became seriously ill. If the record retention period began at the time of production, but the wine was aged at the manufacturer's facility 2 years before distribution into commerce, the record retention period would have expired before the wine entered commerce. In the final rule, FDA retains the requirement that records required under subpart J must be established at the time food is received or released and maintained from that time until the end of the time period specified in § 1.360 of this final rule. (Comment 136) One comment notes that mechanisms for keeping records updated have not been established. The comment asked what should be done if a record's 2-year deadline expires, e.g., is there a requirement to open a new record? (Response) The final rule does not mandate specific mechanisms, systems, or processes for establishing and maintaining the required records, only the information that must be kept. The record retention period is from the time the food is received or released. Persons are not required to update, modify, or transfer information in a record to a new record after the end of the required retention period.

Below, the Department provides the basis for its estimated quantifiable costs resulting from the proposed changes to specific provisions of the Security Rule. Many of the estimates are based on assumptions formed through OCR's experience with compliance and enforcement and accounts from stakeholders. For each cost, the Department provides its main estimate, as well as additional high and low estimates for some costs to account for any uncertainty in the compliance approach of regulated entities. All estimates in this section are based on subject matter expertise. The Department requests information or data points from commenters to further refine its estimates and assumptions.

a. Costs Associated With Conducting a Security Rule Compliance Audit The Department estimates that all regulated entities would need to conduct a Security Rule Compliance Audit because this would be a new requirement under proposed 45 CFR 164.308(a)(14). Although some regulated entities have mistakenly conducted such an audit in lieu of a risk analysis, the Department believes that costs for the compliance audit as a separate requirement should be attributed to the proposed changes in the NPRM. Further, because this would be an annual requirement, the Department is including this as a recurring cost. The Department estimates that regulated entities would need an average of 2 hours of labor by an information systems analyst to conduct the compliance audit, based on the assumption that regulated entities have already documented Security Rule compliance activities as currently required. This would result in total estimated costs of \$437,205,288 [= 1,822,600 regulated entities × 2 hours × \$119.94]. The respective low and high estimates would be 0.25 and 2.5 hours of information systems analyst labor, resulting in respective total estimated costs of \$54,650,661 [= 1,822,600 regulated entities × 0.25 hours × \$119.94] and \$546,506,610 [= 1,822,600 regulated entities × 2.5 hours × \$119.94]. (printed page 998)

b. Estimated Costs From Adding a Requirement for Business Associates to Analyze Compliance With Technical Safeguards For proposed 45 CFR 164.308(b)

(d) DA PAM 25-51, The Army Privacy Program-System of Records Notices and Exemption Rules. (e) DOD Directive 5400.11, Department of Defense Privacy Program. (f) DOD 5400.11-R, Department of Defense Privacy Program. (g) AR 25-2, Information Assurance. (h) AR 25-400-2, The Army Records Information Management System (ARIMS). (i) AR 27-10, Military Justice. (j) AR 40-66, Medical Record Administration and Health Care Documentation. (k) AR 60-20 and AFR 147-14, Army and Air Force Exchange Service Operating Policies. (l) AR 190-45, Law Enforcement Reporting. (m) AR 195-2, Criminal Investigation Activities. (n) AR 380-5, Department of Army Information Security Program. (o) DOD Directive 5400-7, DOD Freedom of Information Act (FOIA) Program. (q) DOD 5400.7-R, DOD Freedom of Information Program. (r) DOD 6025.18-R, DOD Health Information Privacy Regulation (HIPAA). (s) U.S. Department of Justice, Freedom of Information Act Guide and Privacy Act Overview. (t) Office of Secretary of Defense memorandum, dated July 15, 2005, subject: Notifying Individuals when Personal Information is Lost, Stolen, or Compromised located at <http://www.army.mil/ciog6/referencs/policy/dos/OSDprivateinfo.pdf>. Appendix B to Part 505-Denial Authorities for Records Under Their Authority (Formerly Access and Amendment Refusal Authorities) (a) The Administrative Assistant to the Secretary of the Army is authorized to act for

the Secretary of the Army on requests for all records maintained by the Office of the Secretary of the Army and its serviced activities, as well as requests requiring the personal attention of the Secretary of the Army. This also includes civilian Equal Employment Opportunity (EEO) actions. (See DCS, G-1 for Military Equal Opportunity (EO) actions). The Administrative Assistant to the Secretary of the Army has delegated this authority to the Chief Attorney, OAASA (See DCS, G1 for Military Equal Opportunity (EO) actions). (b) The Assistant Secretary of the Army (Financial Management and Comptroller) is authorized to act on requests for finance and accounting records. Requests for CONUS finance and accounting records should be referred to the Defense Finance and Accounting Service (DFAS). The Chief Attorney, OAASA, acts on requests for non-finance and accounting records of the Assistant Secretary of the Army (Financial Management and Comptroller). (c) The Assistant Secretary of the Army (Acquisition, Logistics, & Technology) is authorized to act on requests for procurement records other than those under the purview of the Chief of Engineers and the Commander, U.S. Army Materiel Command. The Chief Attorney, OAASA, acts on requests for non-procurement records of the Assistant Secretary of the Army (Acquisition, Logistics and Technology).

As specified in the rule, IoT, IIoT, and OT, are Specialized Assets, and all requirements associated with Specialized Assets apply to any equipment that processes, stores, or transmits CUI but is unable to be fully secured. The description of Internet of Things (IoT) in the level 2 and level 3 Scoping Guides is consistent with the definition of IOT in § 170.4 and is defined in NIST SP 800-172A Mar2022. Scoping Guide text also provides examples to help clarify what types of devices may be IoT. The definition of (printed page 83162) OT is from NIST SP 800-60 V2R1 and the definition of ICS is from NIST SP 800-82r3. Requests for revisions to these definitions should be addressed to NIST. OSAs determine the asset categories and assessment scope based on how and where they will process, store, and transmit FCI and CUI. The DoD declined to comment on individual use cases included in the comments. e. Program and Security Requirements Comment: Two comments asked for a definition of 'Security Requirements' while another asked for the DoD to define the term 'CMMC Program requirements' in the rule. Three comments addressed concerns with the CMMC security practices numbering scheme in §§ 170.14(c)(i). One comment requested clarification on what constitutes a 'priority' program. Another commenter stated the term 'all applicable CMMC security requirements' is ambiguous and many OSAs will only attest to fulfilling the FAR 52.204-21 or NIST SP 800-171 R2 security requirements. The commenter felt this could lead to a significant disconnect at CMMC Level 2 since Level 2 includes security requirements associated with the use of ESPs, as defined in DFARS clause 252.204-7012 paragraphs (e.g., para (b)(2)(ii)(D)) and the DoD CIO FedRAMP Equivalency memorandum. Response: CMMC Program requirements are all the requirements codified in the 32 CFR part 170 CMMC Program rule. The term 'CMMC Security Requirements' is defined in § 170.14(c). The CMMC supplemental guidance documents add clarity; however, they are not authoritative and the rule itself takes precedence. The CMMC numbering scheme in the rule is a key element of the model that must pull together the independent numbering schemes of FAR clause 52.204-21 (for Level 1), NIST SP 800-171 R2 (for Level 2), and NIST SP 800-172 Feb2021 (for Level 3). For the CMMC Program, the numbering scheme must also identify the domain and CMMC Level of each security requirement. The term 'priority program' is not used in the rule; therefore, no definition of this term is needed. A commenter incorrectly associated CMMC Program requirements as CMMC security requirements. To address potential confusion, the rule was updated to define 'CMMC security requirements' as the 15 Level 1 FAR requirements, the 110 NIST SP 800-171 R2 requirements, and the 24 selected NIST SP 800-172 Feb2021 requirements. f. OSA and OSC Comment: Several comments requested clarification of the terms OSA and OSC. One recommended combining them into a single term. Response:

(d) The CMMC Program balances the need to safeguard FCI and CUI and the requirement to share information appropriately with defense contractors in order to develop capabilities for the DoD. The CMMC Program is designed to ensure implementation of cybersecurity practices for defense contractors and to provide DoD with increased assurance that FCI and CUI information will be adequately safeguarded when residing on or transiting contractor information systems. (e) This part creates no right or benefit, substantive or procedural, enforceable by law or in equity by any party against the United States, its departments, agencies, or entities, its officers, employees, or agents, or any other person. § 170.2 Incorporation by Reference. Certain material is incorporated by reference into this part with the approval of the Director of the Federal Register under 5 U.S.C. 552(a) and 1 CFR part 51 . Material approved for (printed page 89119) incorporation by reference (IBR) is available for inspection at the Department of Defense (DoD) and at the National Archives and Records Administration (NARA). Contact DoD online: <https://DoDcio.defense.gov/CMMC/>.

; email osd.mc-alex.DoD-cio.mbx.cmmc-rule@mail.mil ; or phone: (202) 770-9100. For information on the availability of this material at NARA, visit www.archives.gov/federal-register/cfr/ibr-locations.html or email fr.inspection@nara.gov . The material may be obtained from the following sources: (a) National Institute of Standards and Technology, U.S. Department of Commerce, 100 Bureau Drive, Gaithersburg, MD 20899; (301) 975-8443; <https://csrc.nist.gov/publications/> . (1) FIPS PUB 200, Minimum Security Requirements for Federal Information and Information Systems, published March 2006; IBR approved for § 170.4(b). (2) FIPS PUB 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors, published January 2022; IBR approved for § 170.4(b). (3) SP 800-37, revision 2, Risk Management Framework for Information Systems and Organizations, published December 2018; IBR approved for § 170.4(b). (4) SP 800-39, Managing Information Security Risk: Organization, Mission, and Information System View, published March 2011; IBR approved for § 170.4(b). (5) SP 800-53 revision 5, Security and Privacy Controls for Information Systems and Organizations, published September 2020 (includes updates as of Dec. 10, 2020); IBR approved for § 170.4(b). (6) SP 800-82 revision 2, Guide to Industrial Control Systems (ICS) Security, published June 3, 2015, updated November 10, 2018; IBR approved for § 170.4(b). (7) SP 800-115, Technical Guide to Information Security Testing and Assessment, published September 2008; IBR approved for § 170.4(b). (8) SP 800-160, Volume 2, revision 1, Developing Cyber-Resilient Systems: A Systems Security Engineering Approach, published December 2021; IBR approved for §§ 170.4(b).

608. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· *supra* note 461; see also ·Security Standards: Administrative Safeguards,· *supra* note 517, p. 19-22. Back to Citation 609. · See Press Release, ·HHS Office for Civil Rights Settles HIPAA Security Rule Failures for \$950,000,· U.S. Department of Health and Human Services (July 1, 2024), <https://prod-www.hhs.gov/cloud.hhs.gov/about/news/2024/07/01/hhs-office-civil-rights-settles-hipaa-security-rule-failures-950000.html> . Back to Citation 610. · See ·Security Standards: Administrative Safeguards,· *supra* note 517, p. 22. Back to Citation 611. · See proposed 45 CFR 164.308(a)(13)(ii)(A) . Back to Citation 612. · See ·Cybersecurity Program Audit Guide,· GAO-23-104705, U.S. Government Accountability Office, p. 1 (Sept. 28, 2023), <https://www.gao.gov/products/gao-23-104705> ; see also ·Security and Privacy Controls for Information Systems and Organizations,· *supra* note 600. Back to Citation 613. · See ·The IIA's Three Lines Model: An update of the Three Lines of Defense,· The Institute of Internal Auditors, p. 4 (Sept. 9, 2020), <https://www.theiia.org/globalassets/documents/resources/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense-july-2020/three-lines-model-updated-english.pdf> . Back to Citation 614. ·We believe that health plans that are subject to HIPAA and to the Employee Retirement Income Security Act of 1974 could comply with the proposed compliance audit requirement and follow the Employee Benefits Security Administration's Cybersecurity Program Best Practices, which specifies that all such plans have a reliable annual third party audit of security controls. ·Cybersecurity Program Best Practices,· Employee Benefits Security Administration, U.S. Department of Labor, p. 1, 2 (Apr. 2021), https://www.dol.gov/sites/dolgov/files/ebsa/pdf_files/best-practices.pdf; ·Cybersecurity Guidance Update,· Employee Benefits Security Administration, U.S. Department of Labor (Sept. 6, 2024), <https://www.dol.gov/agencies/ebsa/key-topics/retirement-benefits/cybersecurity/compliance-assistance-release-2024-01> . Back to Citation 615. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· *supra* note 461. Back to Citation 616. *Id.* at 54. Back to Citation 617. *Id.* Back to Citation 618. · See 45 CFR 164.306(a)(1) . Back to Citation 619. · See 45 CFR 164.308(b) . Back to Citation 620. · See proposed 45 CFR 164.308(b)(1)(i) and (ii) . Back to Citation 621. *Id.* Back to Citation 622. · See proposed 45 CFR 164.308(b)(2)(ii) . Back to Citation 623. *Id.* Back to Citation 624. ·Proposed 45 CFR 164.308(b)(2)(ii)(A) . Back to Citation 625. *Id.* Back to Citation 626. ·Proposed 45 CFR 164.308(b)(2)(ii)(B) . Back to Citation 627. ·Cybersecurity Performance Goals,· *supra* note 18; see also proposed 45 CFR 164.308(b)(2)(i) . Back to Citation

For questions about this Notice contact: Jon Boyens, International Trade Administration, U.S. Department of Commerce, 1401 Constitution Avenue, NW., Room 2806, Washington, DC 20230, telephone (202) 482-0573, e-mail Jon.Boyens@trade.gov ; or Alfred Lee, National Telecommunications and Information Administration, U.S. Department of Commerce, 1401 Constitution Avenue, NW., Room 4725, Washington, DC 20230, telephone (202) 482-1880, e-mail Alee@ntia.doc.gov . Please direct media

inquires to the National Institute of Standards and Technology's Office of Public and Business Affairs at (301) 975-6478. SUPPLEMENTARY INFORMATION: The Internet has become vitally important to U.S. innovation, prosperity, education, civic activity and cultural life as well as aspects of our national security. A top priority of the Department of Commerce is to ensure that the Internet remains an open and trusted infrastructure, both for commercial entities and individuals. In pursuit of this priority, the Department has created an Internet Policy Task Force whose mission is to identify leading policy challenges and to recommend possible solutions. The Task Force leverages expertise across many bureaus at the Department, including those responsible for cybersecurity standards and best practices, information and communications policy, international trade, intellectual property, business advocacy and export control. This Notice of Inquiry is one in a series of inquiries from the Task Force. Other reviews examine information privacy, global free flow of information on the Internet, and online copyright protection issues. The Task Force may explore additional areas in the future. The Task Force's cybersecurity work aims to identify public policies and private-sector norms that can: (1) Promote conduct by firms and consumers that collectively will sustain growth in the Internet economy and improve the level of security of the infrastructure and online environment that support it; (2) enhance individual and collaborative efforts by those actors who are in the best position to assist firms and their customers in addressing cybersecurity challenges; (3) improve the ability of firms and consumers to keep pace with ever-evolving cybersecurity risks; and (4) promote individual privacy and civil liberties. Public policies and private-sector practices that promote innovation and enhance cybersecurity will help assure that the Internet remains fertile ground for an expanding range of beneficial commercial and consumer activity. Internet Growth and Evolving Cybersecurity Challenges: The Internet allows users to gather, store, process, and transfer vast amounts of data, including proprietary and sensitive business, transactional, and personal data. At the same time that businesses and consumers rely more and more on such capabilities, cybersecurity risks continue to plague the Internet economy, and it seems highly unlikely that all risks will ever be completely eliminated. (printed page 44217)

IA.L2-3.5.1 · Identification [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13 112
 Identification and Authentication (IA) IA.L2-3.5.1 · IDENTIFICATION [CUI DATA] Identify system users, processes acting on behalf of users, and devices. ASSESSMENT OBJECTIVES [NIST SP 800-171A]98 Determine if: [a] system users are identified; [b] processes acting on behalf of users are identified; and [c] devices accessing the system are identified. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]98 Examine [SELECT FROM: Identification and authentication policy; procedures addressing user identification and authentication; system security plan, system design documentation; system configuration settings and associated documentation; system audit logs and records; list of system accounts; other relevant documents or records]. Interview [SELECT FROM: Personnel with system operations responsibilities; personnel with information security responsibilities; system or network administrators; personnel with account management responsibilities; system developers]. Test [SELECT FROM: Organizational processes for uniquely identifying and authenticating users; mechanisms supporting or implementing identification and authentication capability]. DISCUSSION [NIST SP 800-171 REV. 2]99 Common device identifiers include media access control (MAC), Internet Protocol (IP) addresses, or device -unique token identifiers . Management of individual identifiers is not applicable to shared system accounts . Typically, individual identifiers are the user names associated with the system accounts assigned to those individuals . Organizations may require unique identification of individuals in group accounts or for detailed accountability of individual activity. In addition, this requirement addresses individual identifiers that are not necessarily associated with system accounts . Organizational devices requiring 98 NIST SP 800-171A, p. 31. 99 NIST SP 800-171 Rev. 2, p. 23.

(Response) FDA agrees in part with the comments. The final rule has been revised from the proposal. The final rule provides five alternatives for transporters to meet their obligation to establish and maintain records. First, transporters can meet the requirements of this final rule by keeping the records listed in §1.352(a) of this final rule. Second, transporters can meet the requirements of this final rule by keeping the records listed in §1.352(b) of this final rule, which are included within the current requirements for roadway interstate transporters under FMCSA regulations as of the date of publication of this final rule (49 CFR 373.101 and 373.103). Third, transporters can meet the requirements of this final rule by keeping the records listed in §1.352(c) of this final rule, which are included within the current requirements for rail and water interstate transporters under STB regulations as of the date of publication of this final rule (49 CFR 1035.1

and 1035.2). Fourth, transporters can meet the requirements of this final rule by keeping the records listed in § 1.352(d) of this final rule, which are included with the current requirements for international air transporters under the Warsaw Convention. Fifth, transporters can meet the requirements of this final rule by entering into an agreement with a nontransporter immediate previous source in the United States or a nontransporter immediate subsequent recipient in the United States to keep records for them. Such agreements must (printed page 71594) contain the elements specified in § 1.352(e) of this final rule. Failure by the immediate previous source or immediate subsequent recipient who enters into an agreement under § 1.352(c) of this final rule to keep such records is a prohibited act under § 1.363 of this final rule. FDA notes that the FMCSA and STB regulations only apply to interstate transporters, and this final rule applies to both interstate and intrastate transporters. Intrastate transporters will be subject to the requirements of this final rule because FDA has determined that imposing such requirements on intrastate transporters comports with the Constitution, and these requirements are necessary to allow FDA to identify the immediate previous sources and immediate subsequent recipients of food in order to address credible threats of serious adverse health consequences or death. Intrastate transporters can meet this obligation by complying with either § 1.352(a), (b), (c), (d), or (e) of this final rule. As a practical matter, because the final rule's requirements for interstate shipments can be satisfied by existing records relating to interstate shipments, the final rule only establishes new requirements for (1) intrastate transporters ; and (2) intrastate shipments conveyed by interstate transporters

5. Clarifying the Definition of ·Confidentiality· 6. Adding Definitions of ·Deploy· and ·Implement· 7. Adding a Definition of ·Electronic Information System· 8. Modifying the Definition of ·Information System· 9. Modifying the Definition of ·Malicious software· 10. Adding a Definition of ·Multi-factor Authentication· (MFA) 11. Clarifying the Definition of ·Password· 12. Clarifying the Definition of ·Physical Safeguards· 13. Adding a Definition of ·Relevant Electronic Information System· 14. Adding a Definition of ·Risk· 15. Clarifying the Definitions of ·Security or Security Measures· and ·Security Incident· 16. Adding Definitions of ·Technical Controls· 17. Modifying the Definition of ·Technical Safeguards· 18. Adding a Definition of ·Technology Asset· 19. Adding a Definition of ·Threat· 20. Clarifying the Definition of ·User· 21. Adding a Definition of ·Vulnerability· 22. Clarifying the Definition of ·Workstation· 23. Request for Comment C. Section 164.306·Security Standards: General Rules 1. Current Provisions 2. Issues To Address 3. Proposals 4. Request for Comment D. Section 164.308·Administrative Safeguards 1. Current Provisions 2. Issues To Address 3. Proposals 4. Request for Comment E. Section 164.310·Physical Safeguards 1. Current Provisions 2. Issues To Address 3. Proposals 4. Request for Comment F. Section 164.312·Technical Safeguards 1. Current Provisions 2. Issues To Address 3. Proposals 4. Request for Comment G. Section 164.314·Organizational Requirements 1. Section 164.314(a)(1)·Standard: Business Associate Contracts or Other Arrangements 2. Section 164.314(b)(1)·Standard: Requirements for Group Health Plans 3. Request for Comment H. Section 164.316·Documentation Requirements 1. Current Provisions 2. Issues To Address 3. Proposals 4. Request for Comment I. Section 164.318·Transition Provisions 1. Current Provisions and Issues To Address 2. Proposal 3. Request for Comment J. Section 164.320·Severability K. New and Emerging Technologies Request for Information 1. Quantum Computing 2. Artificial Intelligence (AI) 3. Virtual and Augmented Reality (VR and AR) 4. Request for Comment V. Regulatory Impact Analysis A. Executive Order 12866 and Related Executive Orders on Regulatory Review 1. Summary of Costs and Benefits 2. Baseline Conditions 3. Costs of the Proposed Rule 4. Benefits of the Proposed Rule 5. Comparison of Benefits and Costs B. Regulatory Alternatives to the Proposed Rule C. Regulatory Flexibility Act·Small Entity Analysis D. Executive Order 13132 ·Federalism E. Assessment of Federal Regulation and Policies on Families F. Paperwork Reduction Act of 1995 1. Explanation of Estimated Annualized Burden Hours I. Executive Summary A. Overview

c. DFARS provision 252.239-7009, Representation of Use of Cloud Computing, requires contractors to report that they ·anticipate· or ·do not anticipate· utilizing cloud computing service in performance of the resultant contract. The representation will notify contracting officers of the applicability of the cloud computing requirements at DFARS clause 252.239-7010 of the contract. d. DFARS clause 252.239-7010, Cloud Computing Services, requires reporting of cyber incidents that occur when DoD is purchasing cloud computing services. These DFARS provisions and clauses facilitate mandatory cyber incident reporting requirements in accordance with statutory regulations. When reports are submitted, DoD will analyze the reported information for cyber threats and vulnerabilities in order to develop response measures as well as improve U.S. Government

understanding of advanced cyber threat activity. In addition, the security requirements in NIST SP 800-171 are specifically tailored for use in protecting sensitive information residing in contractor information systems and generally reduce the burden placed on contractors by eliminating Federal-centric processes and requirements. The information provided will inform DoD in assessing the overall risk to DoD covered defense information on unclassified contractor systems and networks. Comments and recommendations on the proposed information collection should be sent to Ms. Susan Minson, DoD Desk Officer, at Oira_submission@omb.eop.gov . Please identify the proposed information collection by DoD Desk Officer and the Docket ID number and title of the information collection. You may also submit comments, identified by docket number and title, by the following method: Federal eRulemaking Portal: <https://www.regulations.gov> . Follow the instructions for submitting comments. DoD Clearance Officer : Ms. Angela Duncan. Requests for copies of the information collection proposal should be sent to Ms. Duncan at whs.mc-alex.esd.mbx.dd-dod-information-collections@mail.mil . Jennifer D. Johnson, Editor/Publisher, Defense Acquisition Regulations System. [FR Doc. 2022-18769 Filed 8-30-22; 8:45 am] BILLING CODE 5001-06-P

Assessment scores must be reported to the Department via SPRS. SPRS scores must be submitted by the time of contract award and not be more than three years old. DFARS clause 252.204-7020 notifies contractors that DoD reserves the right to conduct a higher-level assessment of contractors' cybersecurity compliance, and contractors must give DoD assessors full access to their facilities, systems, and personnel. Further, DFARS clause 252.204-7020 complements DFARS clause 252.204-7012's flow down requirements by holding contractors responsible for confirming their subcontractors have SPRS scores on file prior to awarding them contracts. DFARS clause 252.204-7021 paves the way for rollout of the CMMC Program. Once CMMC is implemented, the required CMMC Level and assessment type will be specified in the solicitation and resulting contract. Contractors handling FCI or CUI will be required to meet the CMMC requirement specified in the contract. DFARS clause 252.204-7021 also stipulates contractors will be responsible for flowing down the CMMC requirements to their subcontractors. CFR Part 170-Additional Requirements for Defense Contractors and Subcontractors Discussed in This Final Rule When this 32 CFR part 170 CMMC Program rule and the complementary 48 CFR part 204 CMMC Acquisition rule are finalized and following a phased implementation plan, solicitations and resulting defense contracts involving the processing, storing, or transmitting of FCI or CUI on a non-Federal system will, unless waived, have a CMMC level and assessment type requirement that a contractor must meet to be eligible for a contract award. The four phases of the implementation plan add CMMC level requirements incrementally, starting in Phase 1 with self-assessments, and ending in Phase 4, which represents full implementation of program requirements. The DoD elected to base the phase-in plan on the level and type of assessment to provide time to train the necessary number of assessors, and to allow companies time to understand and implement CMMC requirements. Details of each phase are addressed in (printed page 83095) §.170.3(e). In Phases 2 and 3, DoD will implement CMMC Level 2 and Level 3 certification requirements, respectively. At full implementation (Phase 4), DoD will include CMMC requirements in all applicable DoD contracts and option periods on contracts awarded after the beginning of Phase 4. Table 1 defines the requirements for each CMMC level and assessment type. Table 1.CMMC Level and Assessment Requirements CMMC status Source & number of security reqts. Assessment reqts. Plan of action & milestones (POA&M) reqts. Affirmation reqts. Level 1 (Self) · 15 required by FAR clause 52.204-21 · Conducted by Organization Seeking Assessment (OSA) annually · Results entered into SPRS (or its successor capability). · Not permitted · After each assessment. · Entered into SPRS. Level 2 (Self) · 110 NIST SP 800-171 R2 required by DFARS clause 252.204-7012

The notation and terminology for the state are described in Sec. 3.1. The step mappings are specified in Sec. 3.2. The KECCAKp permutations, including the round function Rnd, are specified in Sec. 3.3. The relationship of the KECCAKp permutations to the KECCAKf permutations that were defined for KECCAK in [8] is described in Sec. 3.4.

2. The UFS also stores application information collected when the fee remitter (submitter) creates coversheets in order to pay user fees. This information includes the type of application, waiver and exemption status, and SBD number. 3. The UFS stores fee processing information including: Billing details; adjustments to invoices including credit and debit memos; and receipt information including date, mode, and amount of payment. AUTHORITY FOR MAINTENANCE OF THE SYSTEM: 21 U.S.C. 371 , 379 , 379e , 379h , 379h-1 , 379j , 379j-12 , 379j-21 , 379j-31 , 387s , and 393(d)(2) ; 42 U.S.C. 263b(r)(1) ; 5 U.S.C. 301 , 552 ; and 44 U.S.C. 3101 . PURPOSE(S): FDA personnel and any contractors assisting them will use information in the system, on a need-to-know

basis, for the following purposes: 1. To assess and collect user fees. 2. To provide an electronic payment and receipt mechanism that is integrated with the U.S. Department of Treasury's <http://www.Pay.gov> Web site and the various FDA Centers. 3. To provide Web-based capabilities including transactional inquiries and information on payment status. 4. To facilitate debt collection activities in accordance with the Debt Collection Improvement Act of 1996 and the HHS regulations for claims collections (45 CFR Part 30). ROUTINE USES OF RECORDS MAINTAINED IN THE SYSTEM INCLUDING THE PURPOSES OF SUCH USES AND CATEGORIES OF USERS: Permitted disclosures include those made in accordance with routine uses that are listed in the notice of the system of records. 5 U.S.C. 552a(b)(3) . The Privacy Act defines 'routine use' as 'with respect to the disclosure of a record, the use of such record for a purpose which is compatible with the purpose for which it was collected.' See also FDA's Privacy Act regulations, defining 'routine use' as 'use outside the Department of Health and Human Services that is compatible with the purpose for which the records were collected and described in the [System of Records] notice * * * . 21 CFR 21.20(b)(5) . (printed page 67822) Records in this system that contain information about record subjects and nonsubjects (such as FDA employees who operate the system) may be disclosed to recipients outside HHS in accordance with the following routine uses: 1. Records may be disclosed to appropriate Federal Agencies and Department contractors that have a need to know the information for the purpose of assisting the Department's efforts to respond to a suspected or confirmed breach of the security or confidentiality of information maintained in this system of records. 2. In the event HHS deems it desirable or necessary, in determining whether particular records are required to be disclosed under the FOIA, disclosure may be made to the DOJ for the purpose of obtaining its advice.

<http://www.dtic.mil/whs/directives/corres/pdf/520008r.pdf> . Back to Citation 11. .Available at <http://www.dtic.mil/whs/directives/corres/html/521056.htm> . Back to Citation 12. .Available at <http://www.dtic.mil/whs/directives/corres/pdf/110022p.pdf> . Back to Citation 13. .This requirement is specific to arming procedures. Such written acknowledgement should not be construed to limit potential civil and criminal liability to conduct arising from the use of weapons. For example, PSC personnel could be held criminally liable for any conduct that would constitute a Federal offense (see MEJA, 18 U.S.C. 3261(a)). Back to Citation [FR Doc. 2011-20239 Filed 8-10-11; 8:45 am] BILLING CODE 5001-06-P

(ii) In determining whether an automated system is a system of records that is subject to this part, retrieval policies and practices shall be evaluated. If DoD Component policy is to retrieve personal information by the name or other unique personal identifier, it is a system of records. If DoD Component policy prohibits retrieval by name or other identifier, but the actual practice of the Component is to retrieve information by name or identifier, even if done infrequently, it is a system of records. (2) If records are retrieved by name or personal identifier, a system notice must be submitted in accordance with § 310.33. (3) If records are not retrieved by name or personal identifier but then are rearranged in such a manner that they are retrieved by name or personal identifier, a new systems notice must be submitted in accordance with § 310.33. (4) If records in a system of records are rearranged so that retrieval is no longer by name or other personal identifier, the records are no longer subject to this part and the system notice for the records shall be deleted in accordance with § 310.34. (c) Relevance and necessity. Information or records about an individual shall only be maintained in a system of records that is relevant and necessary to accomplish a DoD Component purpose required by a Federal statute or an Executive Order. (d) Authority to establish systems of records. Identify the specific statute or the Executive Order that authorizes maintaining personal information in each system of records. The existence of a statute or Executive Order mandating the maintenance of a system of records does not abrogate the responsibility to ensure that the information in the system of records is relevant and necessary. If a statute or Executive Order does not expressly direct the creation of a system of records, but the establishment of a system of records is necessary in order to discharge the requirements of the statute or Executive Order, the statute or Executive Order shall be cited as authority. (e) Exercise of First Amendment rights. (1) Do not maintain any records describing how an individual exercises his or her rights guaranteed by the First Amendment of the U.S. Constitution except when: (i) Expressly authorized by Federal statute; (ii) Expressly authorized by the individual; or (iii) Maintenance of the information is pertinent to and within the scope of an authorized law enforcement activity. (2) First Amendment rights include, but are not limited to, freedom of religion, freedom of political beliefs, freedom of speech, freedom of the press, the right to assemble, and the right to petition. (f) System Manager's evaluation. (1) Evaluate the information to be included in each new system before establishing the system and evaluate periodically the information contained in

each existing system of records for relevancy and necessity. Such a review shall also occur when a system notice alteration or amendment is prepared (see § 310.33 and § 310.34).

Adding ·as amended,· after · Public Law 110-181 ·,· ii. Removing ·section 159.5 of this part· and adding in its place ·§ 159.5·. b. In paragraph (b): i. Removing ·Geographic Combatant Commanders· and adding in its place ·Combatant Commanders (CCDRs) with geographic Areas of Responsibility (AORs)·. ii. Redesignating footnotes 4 and 5 as footnotes 1 and 2. c. In paragraph (c): i. Removing ·geographic Combatant Commander· and adding in its place ·CCDR for the applicable geographic AOR· wherever it appears. ii. Adding ·(COM)· after ·the relevant Chief of Mission· in the first sentence. iii. Removing ·Chief of Mission· and adding in its place ·COM· in the second sentence. 6. Revise § 159.5 to read as follows: § 159.5 Responsibilities. (a) The Under Secretary of Defense for Personnel and Readiness (USD(P&R)) will provide Department-wide policies on the total force manpower mix and labor sourcing, consistent with U.S. law, the FAR, the DFARS, and other applicable Federal policy documents, especially with respect to contracted services and restrictions on functions that contractors may and may not perform. The USD(P&R) will ensure that policies specifically address circumstances where use of PSCs would be inherently governmental or where CCDRs with geographic AORs would need to assess where performance of the function by PSCs or total reliance on PSCs would constitute an unacceptable risk. (b) The Deputy Assistant Secretary of Defense for Logistics (DASD(Logistics)), under the authority, direction, and control of the Under Secretary of Defense for Acquisition and Sustainment (USD(A&S)) and through the Assistant Secretary of Defense for Sustainment, monitors the registering, processing, and accounting of PSC personnel in areas of contingency operations, humanitarian or peace operations, or other military operations or exercises. (c) The Principal Director, Defense Pricing and Contracting (DPC), under the authority, direction, and control of the USD(A&S) and through the Assistant Secretary of Defense for Acquisition, ensures that the DFARS and (when appropriate, in consultation with the other members of the FAR Council) the FAR, provides appropriate guidance and publishes contracting requirements pursuant to this part and section 862 of Public Law 110-181 . (d) The CJCS shall ensure that joint doctrine is consistent with the principles established by DoD Directive 3020.49, ·Program Management for the Planning and Execution of Operational Contract Support· (available at <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodd/302049d.pdf?ver=fgxC1kzBqeIV4KpOv9pDTw%3d%3d>); DoD Instruction 3020.41, DoD Directive 5210.56, ·Arming and the Use of Force· (available at <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodd/521056p.PDF?ver=Plvlb3eh t0obgolnD0UCEw%3d%3d>); and this part.

DCMA DIBCAC submits assessment appeals, review records, and decision results of assessment appeals using the CMMC instantiation of eMASS as addressed in § 170.7(a)(2) and (6) of this part. Additional information collection reporting and recordkeeping requirements for this part include: OSCs prepare for assessment based on NIST guidelines as addressed in § 170.18. DCMA DIBCAC conducts assessment based on NIST guidelines as addressed in § 170.18. This is an assessment to validate implementation of 24 selected security requirements from NIST SP 800-172. OSCs may have a POA&M at CMMC Level 3 as addressed in § 170.21(a)(3). DCMA DIBCAC must perform a POA&M closeout assessment. OSCs may submit appeals to DCMA DIBCAC as addressed in § 170.7(a)(6). OSCs must retain artifacts used as evidence for the assessment for the duration of the validity period of the certificate of assessment, and at minimum, for six (6) years from the date of certification assessment as addressed in § 170.18(c)(4). DCMA DIBCAC maintains records for a period of six years of monitoring, education, training, technical knowledge, skills, experience, and authorization of each member of its personnel involved in inspection activities and working papers generated from Level 3 Certification Assessments. The public and government respondent burden and labor cost for the information collection reporting and recordkeeping requirements under the CMMC Level 3 Certification Assessment are as follows: Note: This respondent burden and labor cost does not include the requirement for the OSC to upload the affirmation in SPRS (addressed in Title 48 acquisition rule and ICR). (printed page 89116) (printed page 89117) Part B: Respondent Costs Other Than Burden Hour Costs Non-Recurring and Recurring Engineering estimated costs are included for Level 3 Certification Assessments. Non-recurring Engineering reflects a one-time cost consisting of hardware, software, and the associated labor to implement the same. Recurring Engineering reflects annually recurring fees and associated labor for technology refresh. The estimated amounts are average annual amounts for the entity types indicated. Part C: Operational and Maintenance Costs Government operational and maintenance costs include the estimate to develop the operational CMMC instantiation of eMASS. The estimated average annual amount is \$2,731,861. Estimation of Total Public and Government Burden and Cost Needs and Uses: The CMMC Program provides for the assessment

of contractor and subcontractor implementation of DoD cybersecurity requirements for contractor information systems and enhances the protection of FCI and CUI within the DoD supply chain. The CMMC Program will be implemented in DFARS to incorporate CMMC Program requirements into defense contracts and subcontracts. Affected Public: Businesses or other for-profit or not-for-profit entities. Frequency: On occasion. Commenter's Obligation: Voluntary. OMB Desk Officer:

. A CMMC Level 2 assessment must be conducted for each OSC information system that will be used in the execution of the contract that will process, store, or transmit CUI. CMMC Level 3 Certification Assessment Receipt of a CMMC Level 2 Final Certification Assessment for information systems within the Level 3 CMMC Assessment Scope is a prerequisite for a CMMC Level 3 Certification Assessment. A CMMC Level 3 Certification Assessment, conducted by DCMA Defense Industrial Base Cybersecurity Assessment Center (DIBCAC), verifies that an OSC has implemented the CMMC Level 3 security requirements to protect CUI as specified in 32 CFR 170.14(c)(4). A CMMC Level 3 Certification Assessment must be conducted for each OSC information system that will be used in the execution of the contract that will process, store, or transmit CUI. Impact and Cost Analysis of CMMC 2.0 Summary of Impact Public comment feedback on CMMC 1.0 indicated that cost estimates were too low. CMMC 2.0 cost estimates account for that feedback with the following improvements: Allowance for outsourced IT services Increased total time for the contractor to prepare for the assessment, including limited time for learning the reporting and affirmation processes Allowance for use of consulting firms to assist with the assessment process Time for a senior level manager to review the assessment and affirmation before submitting the results in SPRS Updated government and contractor labor rates that include applicable burden costs As a result, some CMMC 2.0 costs may be higher than those included in CMMC 1.0. The CMMC 2.0 impact analysis includes estimated costs for implementation of CMMC 2.0 requirements across Level 1, Level 2, and Level 3 for the Public (small and other than small entities, including the CMMC Ecosystem as set forth in 32 CFR Subpart C) and the Government. In summary, the total estimated Public and Government costs associated with this rule, calculated for a 20-year horizon in 2023 dollars at a 7 percent discount rate and a 3 percent discount rate are provided as follows: Estimating the number of CMMC assessments for unique entities per level per year is complicated by the fact that companies may serve as a prime contractor on one effort but a subcontractor on others, and may also enter into subcontract agreements with more than one prime contractor for various opportunities.

DFARS 252.204-7021 (Cybersecurity Maturity Model Certification Requirements) Requires CMMC certification at the level specified in the contract, effective Phase 1 November 10, 2025. Non-compliance with 252.204-7021 can result in: loss of contract eligibility, termination for cause, False Claims Act liability (if contractor misrepresented compliance status), suspension or debarment from future DoD contracting, and in cases involving CUI spillage or breach, potential civil or criminal penalties.

CIS Safeguard 13.9 · Deploy Port-Level Access Control Deploy port-level access control. Port-level access control utilizes 802.1x, or similar network access control protocols, such as certificates, and may incorporate user and/or device authentication. Implementation Groups: 3 Asset Type: devices Security Function: protect Parent Control: Network Monitoring and Defense

; docket DOD-2018-OS-0075-0001) that claimed certain Privacy Act exemptions for the Personnel Vetting Records System. The Personnel Vetting Records System contains records that support DoD in conducting end-to-end personnel security, suitability, fitness, and credentialing processes, including submission of applications and questionnaires, investigations, adjudications, and continuous vetting activities. DoD developed the information technology capabilities that contribute to the Personnel Vetting Records System to support background investigation processes pursuant to Executive Order 13467 , as amended, and Section 925 of the National Defense Authorization Act for Fiscal Year 2018. The interim final exemption rule for this records system resulted in amendment to and some slight restructuring of § 310.30 (addressing DoD-wide exemptions) of the previous DoD Privacy Program regulation. DoD is incorporating the final version of the exemption rule into this DoD Privacy Program final rule in Section 310.13, which corresponds to § 310.30 of the previous DoD Privacy Program regulation. Additionally, DoD is correcting a clerical error that appeared in § 310.13 of the interim final rule publication concerning the DUSDI 01-DoD, ·Department of Defense (DoD) Insider Threat Management and Analysis Center (DITMAC) and DoD Component Insider Threat Records System. Section 310.13(a)(1)(ii) inaccurately listed authority pursuant to 5 U.S.C. 552a(k)(3) rather than 5 U.S.C. 552a(k)(4) . This final rule accurately reflects the (k)(4)

exemption in § 310.13(e)(1)(ii). During further internal review, it was also discovered that three existing exemption rules were inadvertently omitted from the proposed rule's Subpart C, Exemption Rules. These exemption rules have been included in the final revision of part 310, without amendment, in order to consolidate and streamline existing DoD regulations, and are as follows: Section 310.15: (35) System identifier and name: Army A0600-20-SAMR, Soldiers Equal Opportunity Investigative Files; § 310.16: (24) System identifier and name: N05800-2, Professional Responsibility Files and (25) System identifier and name: NM03800-1, Naval Global Maritime, Foreign Counterterrorism and Counter Intelligence Operation Records. These exemption rules were previously promulgated in accordance with the requirements of 5 U.S.C. 553(b)(1), (2), and (3), (c) and (e) and published in parts 505 and 701. Finally, minor edits were also made to § 310.3 to clarify that individuals may also request to be notified whether a system of records contains records pertaining to them and consistent with the aforementioned restructuring concerning DoD-wide exemptions to § 310.13(b)(1) to clarify the scope and applicability of an exemption when information is provided by confidential sources. Public Comments Received on the DoD Privacy Program Rule As previously referenced, on Thursday, September 13, 2018 (83 FR 46542

Id allow installation or execution. | | 3) Gain Foothold | The attacker has gained entry to the assessment object and achieves enough compromise to gain a foothold, but without persistence. Examples include: unauthorized user successfully logs in with authorized credentials; browser exploit code successfully executed in memory and initiates call back; person gains unauthorized access to server room. | Block Foothold: Reduce number of devices susceptible to compromise due to unauthorized software being allowed to execute. | | 4) Gain Persistence | The attack has gained a foothold on the object and now achieves persistence. Examples include: malware installed on host that survives reboot or log off; basic input/output system (BIOS) or kernel modified; new/privileged account created for unauthorized user; unauthorized person issued credentials/allowed access; unauthorized personnel added to access control list (ACL) for server room. | Block Persistence/Prevent: Stop or delay compromise of devices by restricting software installation. Block Persistence/Detect: Reduce amount of time that malicious or compromised software is installed or remains active before detection and removal. | | 6) Achieve Attack Objective | The attacker achieves an objective. Loss of confidentiality, integrity, or availability of data or system capability. Examples include: exfiltration of files; modification of database entries; deletion of file or application; denial of service; disclosure of personally identifiable information (PII). | Restore required and authorized software as needed, after being removed or altered by attackers, contingency (disk failure), or by mistake. |

Server administrators are system architects responsible for the overall design, implementation, and maintenance of a server. Network administrators are responsible for the overall design, implementation, and maintenance of a network. Security administrators are dedicated to performing information security functions for servers and other hosts, as well as networks. Organizations that have a dedicated information security team usually have security administrators. On a daily basis, server, network, and security administrators contend with the security requirements of the specific systems for which they are responsible. Security issues and solutions can originate from either outside (e.g., security patches and fixes from the manufacturer or computer security incident response teams) or within the organization (e.g., the security office). The administrators are responsible for the following activities associated with servers: -

GLYPH<c=31;font=/MIJOHI+Webdings> Anti-malware software, such as antivirus software, anti-spyware software, and rootkit detectors, to protect the local OS from malware and to detect and eradicate any infections that occur. 20 Examples of when anti-malware software would be helpful include a system administrator bringing infected media to the server and a network service worm contacting the server and infecting it. - GLYPH<c=31;font=/MIJOHI+Webdings> Host-based intrusion detection and prevention software (IDPS), to detect attacks performed against the server, including DoS attacks. For example, one form of host-based IDPS, file integrity checking software, can identify changes to critical system files. 20 Additional information on anti-malware software is available from NIST SP 800-83, Guide to Malware Incident Prevention and Handling (<http://csrc.nist.gov/publications/PubsSPs.html>).

(4) Requests for information recommended for denial will be forwarded to the appropriate Denial Authority, along with a copy of the records and justification for withholding the record. At the same time, notify the requester of the referral to the Denial Authority for action. All documents or portions thereof determined to be releasable to the requester will be released to the requester

before forwarding the case to the Denial Authority. (5) Within 30 working days, the Denial Authority will provide the following notification to the requester in writing if the decision is to deny the requester access to the information. (6) Included in the notification will be: (i) Denying Official's name, position title, and business address; (ii) Date of the denial; (iii) The specific reason for the denial, citing the appropriate subsections of the Privacy Act, the Freedom of Information Act, AR 25-55, The Department of the Army Freedom of Information Act Program and this part; and (iv) The individual's right to administratively appeal the denial within 60 calendar days of the mailing date of the notice, through the Denial Authority, to the Office of the General Counsel, Secretary of the Army, 104 Army Pentagon, Washington, DC 20310-0104. (7) The appeal must be in writing and the requester should provide a copy of the denial letter and a statement of their reasons for seeking review. (8) For denials made by the DA when the record is maintained in a Government-wide system of records, an individual's request for further review must be addressed to each of the appropriate government Privacy Act offices listed in the Privacy Act system of records notices. For a current listing of Government-wide Privacy Act system of records notices see the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy> or DA PAM 25-51. (j) No records determinations. (1) Since a no record response may be considered an adverse determination, the Denial Authority must make the final determination that no records exist. The originating agency shall notify the requester that an initial determination has been made that there are no responsive records, however the final determination will be made by the Denial Authority. A no records certificate must accompany a no records determination that is forwarded to the Denial Authority. (2) The Denial Authority must provide the requester with appeal rights. (k) Referral of requests.

Access to NATO classified information requires a final determination that an individual is eligible for access to classified information at the equivalent level. (7) NATO briefings. Before having access to NATO classified information, the contractor will give employees a NATO security briefing that covers the requirements of this section and the consequences of negligent handling of NATO classified information. A representative of the CSA will give the initial briefing to the contractor. The contractor must conduct annual refresher briefings. (i) When access to NATO classified information is no longer required, the contractor will debrief the employees. The employees will sign a certificate stating that they have been briefed or debriefed, as applicable, and acknowledge their responsibility for safeguarding NATO information. (ii) The contractor will maintain certificates for two years for NATO SECRET and CONFIDENTIAL, and three years for COSMIC TOP SECRET and all ATOMAL information. The contractor will maintain a record of all NATO briefings and debriefings in the CSA-designated database. (8) Access to NATO classified information by foreign nationals. Foreign nationals of non-NATO nations may have access to NATO classified information only with the consent of the NATO Office of Security and the contracting activity. (i) Requests will be submitted to the Central U.S. Registry (CUSR). (ii) Access to NATO classified information may be permitted for citizens of NATO member nations, provided a NATO security clearance certificate is provided by their government and they have been briefed. (9) Subcontracting for NATO contracts. The contractor will obtain prior written approval from the NATO contracting activity and a NATO FSCC must be issued prior to awarding the subcontract. The contractor will forward the request for approval through the CSA. (10) Preparing and marking NATO documents. All classified documents created by a U.S. contractor will be portion-marked. Any portion extracted from a NATO document that is not portion marked, must be assigned the classification that is assigned to the NATO document. (i) All U.S.-originated NATO classified documents will bear an assigned reference number and date on the first page. The reference numbers will be assigned as follows: (A) The first element will be the abbreviation for the name of the contractor. (B) The second element will be the abbreviation for the highest classification followed by a hyphen and the 4-digit sequence number for the document within that classification that has been generated for the applicable calendar year. (C) The third element will be the year; e.g., MM/NS-0013/17. (ii) COSMIC TOP SECRET, NATO SECRET, and ATOMAL documents will bear the reference number on each page and a copy number on the cover or first page. (A) Copies of NATO documents will be serially numbered. (B) Pages will be numbered.

Analysis of costs to meet CMMC requirements is provided in the regulatory impact analysis for this rule. The CMMC rule does not make any change to cost allowability as defined in the FAR 31.201-2 Determining Allowability. Verifying compliance with applicable security requirements may increase cost and is necessary for the protection of DoD CUI. With the revised CMMC, the DoD has streamlined requirements to align directly to NIST guidelines and has eliminated unique security practices to ease the burden on smaller companies. DoD must enforce CMMC requirements uniformly across the

Defense Industrial Base for all contractors and subcontractors who process, store, or transmit CUI. The value of information (and impact of its loss) does not diminish when the information moves to contractors and subcontractors. The DoD declines to speculate about how OSCs and C3PAOs negotiate mutually acceptable terms and conditions for assessment agreements. The DoD declined to modify the estimates, which are intended to be representative and to inform rulemaking.

b. Disproportionate Cost Burden Comment: Many comments emphasized the importance of small business to the DoD contracting environment and expressed the concern that increased cost burden on small companies will result in an anti-competitive barrier to entry. Specifically, commenters state the lack of in-house security resources, inability to amortize costs, upfront costs to comply with CMMC Level 1 and 2 without guaranteed contracts, keeping pace with requirements changes, paying market rates for C3PAO assessments, and obtaining perfect compliance with requirement or assessment objectives may not be affordable or may cause unacceptable enterprise disruption. One comment asserted that the DoD is not considering additional costs to small- and medium-sized businesses (SMBs) for ongoing compliance. One comment stated the cost of entry for a new SMB may be insurmountable even with cost recovery. One comment suggested right-sizing CMMC by tailoring security requirements based on business size and number of employees. Additionally, one comment asserted that small businesses would be unfairly punished while large, legacy primes would lobby and get waivers. Two comments noted that CMMC will increase costs, perhaps doubling annual IT and security spending, ultimately passing the cost to customers, the government and the taxpayer and asked how the DoD plans to deal with price increases from subcontractors and primes. One comment suggested the DoD pay contractor employees to learn to cyber defend rather than pay auditor assessment costs. Response:

anti-virus product quarantines a suspicious file that matches the signature of malicious software. - Compensating : Apply one or more cybersecurity controls to adjust for a weakness in another control. Example: alarms on a server room door audibly notify nearby personnel when an emergency exit push bar has been used, thereby compensating for a physical access control that has been bypassed.

Guidelines on PDA Forensics ## Guidelines on PDA Forensics Personal Digital Assistants (PDAs) are a relatively recent phenomenon, not usually covered in classical computer forensics. This guide attempts to bridge that gap by providing an in-depth look into PDAs and explaining the technologies involved and their relationship to forensic procedures. It covers three families of devices Pocket PC, Palm OS, and Linux-based PDAs - and the characteristics of their associated operating system. This guide also discusses procedures for the preservation, acquisition, examination, analysis, and reporting of digital information present on PDAs, as well as available forensic software tools that support those activities.

(i) Completing and submitting Standard Form (SF) 328 (www.gsa.gov/reference/forms/certificate-pertaining-to-foreign-interests), Certificate Pertaining to Foreign Interests, upon request from DCSA and undergo a National Security Review with regards to the protection of controlled unclassified information based on the factors identified in 32 CFR 117.11(b) using the procedures outlined in 32 CFR 117.11(c) . (ii) Receiving a non-disqualifying eligibility determination from the CMMC PMO resulting from the FOCI risk assessment in order to proceed to a DCMA DIBCAC CMMC Level 2 assessment, as part of the authorization and accreditation process set forth in paragraph (b)(6) of this section. (iii) Reporting any change to the information provided on its SF 328 by resubmitting the SF 328 to DCSA within 15 business days of the change being effective. A disqualifying eligibility determination, based on the results of the change, will result in the C3PAO losing its authorization or accreditation. (6) Undergo a Level 2 certification assessment meeting all requirements for a Final Level 2 (C3PAO) in accordance with the procedures specified in § 170.17(a)(1) and (c), with the following exceptions: (i) The assessment will be conducted by DCMA DIBCAC. (ii) The assessment will not result in a CMMC Status of Level 2 (C3PAO) nor receive a Certificate of CMMC Status. (7) Provide all documentation and records in English. (8) Submit pre-assessment and planning material, final assessment reports, and CMMC certificates of assessment into the CMMC instantiation of eMASS. (9) Unless disposition is otherwise authorized by the CMMC PMO, maintain all assessment related records for a period of six (6) years. Such records include any materials generated by the C3PAO in the course of an assessment, any working papers generated from Level 2 certification assessments; and materials relating to monitoring, education, training, technical knowledge, skills, experience, and authorization of all personnel involved in assessment activities; contractual agreements with OSCs; and organizations for whom consulting services were provided. (10) Provide any requested audit information, including any out-of-cycle from ISO/IEC 17020:2012(E) requirements, to the Accreditation Body. (11) Ensure that all personally identifiable

information (PII) is encrypted and protected in all C3PAO information systems and databases. (12)
 Meet the requirements for Assessment Team composition. An Assessment Team must include at least two people: a Lead CCA, as defined in § 170.11(b)(10), and at least one other CCA. Additional CCAs and CCPs may also participate on an Assessment Team.

· System Owner · Common Control Provider · Information Owner or Steward · Security Architect · Privacy Architect · Systems Security Engineer · Privacy Engineer · System Security Officer · System Privacy Officer · Enterprise Architect · System Administrator NIST SP 800-37, REVISION 2
 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

APPENDIX E PAGE 134 This publication is available free of charge from:
<https://doi.org/10.6028/NIST.SP.800-37r2> TABLE E-5: ASSESSMENT TASKS, RESPONSIBILITIES, AND SUPPORTING ROLES

RMF TASKS	PRIMARY RESPONSIBILITY	SUPPORTING ROLES
TASK A-1 Assessor Selection	Select the appropriate assessor or assessment team for the type of control assessment to be conducted.	· Authorizing Official or Authorizing Official Designated Representative · Chief Information Officer · Senior Agency Information Security Officer · Senior Agency Official for Privacy
TASK A-2 Assessment Plan	Develop, review, and approve plans to assess implemented controls.	· Authorizing Official or Authorizing Official Designated Representative · Control Assessor · Senior Agency Information Security Officer · Senior Agency Official for Privacy
TASK A-3 Control Assessments	Assess the controls in accordance with the assessment procedures described in assessment plans.	· System Owner · Common Control Provider · Information Owner or Steward · System Security Officer · System Privacy Officer
TASK A-4 Assessment Reports	Prepare the assessment reports documenting the findings and recommendations from the control assessments.	· Control Assessor · System Owner · Common Control Provider · System Security Officer · System Privacy Officer
TASK A-5 Remediation Actions	Conduct initial remediation actions on the controls and reassess remediated controls.	· System Owner · Common Control Provider · Control Assessor · Authorizing Official or Authorizing Official Designated Representative · Senior Agency Information Security Officer · Senior Agency Official for Privacy · Senior Accountable Official for Risk Management or Risk Executive (Function) · Information Owner or Steward · Systems Security Engineer · Privacy Engineer · System Security Officer · System Privacy Officer

is not a significant regulatory action. The rule does not: (1) Have an annual effect on the economy of \$100 million or more or adversely affect in a material way the economy; a section of the economy; productivity; competition; jobs; the environment; public health or safety; or State, local, or tribal governments or communities; (2) Create a serious inconsistency or otherwise interfere with an action taken or planned by another Agency; (printed page 24125) (3) Materially alter the budgetary impact of entitlements, grants, user fees, or loan programs, or the rights and obligations of recipients thereof; or (4) Raise novel legal or policy issues arising out of legal mandates, the President's priorities, or the principles set forth in these Executive Orders. Unfunded Mandates Reform Act (Sec. 202, Pub. L. 104-4) It has been certified that this rule does not contain a Federal mandate that may result in the expenditure by State, local and tribal governments, in aggregate, or by the private sector, of \$100 million or more in any one year. Public Law 96-354, ·Regulatory Flexibility Act· (5 U.S.C. 601) It has been certified that this rule is not subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would not, if promulgated, have a significant economic impact on a substantial number of small entities. Public Law 96-511, ·Paperwork Reduction Act· (44 U.S.C. Chapter 35) It has been certified that this rule does not impose reporting or recordkeeping requirements under the Paperwork Reduction Act of 1995. Executive Order 13132 , ·Federalism· It has been certified that this rule does not have federalism implications, as set forth in Executive Order 13132 . This rule does not have substantial direct effects on: (1) The States; (2) The relationship between the National Government and the States; or (3) The distribution of power and responsibilities among the various levels of Government. List of Subjects in 32 CFR Part 329 Privacy Accordingly, 32 CFR part 329 is proposed to be added to read as follows: PART 329-NATIONAL GUARD BUREAU PRIVACY PROGRAM 329.1 Purpose. 329.2 Applicability. 329.3 Definitions. 329.4 Policy. 329.5 Responsibilities. 329.6 Procedures. 329.7 Exemptions. Authority: Pub. L. 93-579, 88 Stat. 1986 (5 U.S.C. 552a). § 329.1

Purpose. This part implements the policies and procedures outlined in 5 U.S.C. 552a, Office of Management and Budget (OMB) Circular No. A-130, and 32 CFR part 310. This part provides the responsibilities, guidance, and procedures for the National Guard Bureau (NGB) to comply with Federal and DoD Privacy requirements. § 329.2 Applicability. (a) This part applies to the NGB and the records under the custody and control of the Chief, NGB, as defined by DoD Directive (DoDD) 5105.77, entitled 'National Guard Bureau' (Available at <http://www.dtic.mil/whs/directives/corres/pdf/510577p.pdf>).

(A) From subsection (c)(3) because it will enable the Department to conduct certain investigations and relay law enforcement information without compromise of the information, protection of investigative techniques and efforts employed, and identities of confidential sources who might not otherwise come forward and who furnished information under an express promise that the sources' identity would be held in confidence (or prior to the effective date of the Act, under an implied promise). (B) From subsections (e)(1), (e)(4), (G), (H), and (I) because it will provide protection against notification of investigatory material including certain reciprocal investigations and counterintelligence information, which might alert a subject to the fact that an investigation of that individual is taking place, and the disclosure of which would weaken the on-going investigation, reveal investigatory techniques, and place confidential informants in jeopardy who furnished information under an express promise that the source's identity would be held in confidence (or prior to the effective (printed page 14807) date of the Act, under an implied promise). (C) From subsections (d) and (f) because requiring OSD to grant access to records and agency rules for access and amendment of records would unfairly impede the agency's investigation of allegations of unlawful activities. To require OSD to confirm or deny the existence of a record pertaining to a requesting individual may in itself provide an answer to that individual relating to an on-going investigation. The investigation of possible unlawful activities would be jeopardized by agency rules requiring verification of record, disclosure of the record to the subject, and record amendment procedures. (18) System identifier and name. DMDC 12 DoD, Joint Personnel Adjudication System (JPAS). (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (ii) Authority. 5 U.S.C. 552a(k)(5). (iii) Reasons.

CMMC Program final rule). The CMMC instantiation of eMASS electronically transfers certification results to SPRS. For Level 1 and 2 self-assessments, OSAs upload their assessment data directly into SPRS. Use of the CMMC instantiation of eMASS provides DoD visibility into the cybersecurity posture of the defense contractor supply chain and is the mechanism to generate reports on the health of the CMMC Ecosystem. SPRS is DoD's authoritative source for supplier and product performance information. Use of this electronic system to collect CMMC information eliminates the need for contractors to respond directly to multiple DoD requiring activities. SPRS serves as a single repository for Government access to CMMC assessment results. Modifications to information collections in SPRS will be addressed in the 48 CFR part 204 CMMC Acquisition final rule. Non-Duplication The information obtained through this collection is unique and is not already available for use or adaptation from another cleared source. Burden on Small Businesses For Level 1 and 2 self-assessments, OSAs must report annually and triennially, respectively. Level 2 and Level 3 certification assessments must be conducted every three years by a C3PAO or DCMA DIBCAC, respectively. At all levels, an annual affirmation is required. In all cases, the burden applied to small business is the minimum consistent with applicable laws, Executive orders, regulations, and prudent business practices. A C3PAO, although not a defense contractor, may also be a small business. Efforts to minimize the burden on C3PAOs include the electronic collection of data using the CMMC instantiation of eMASS and providing Microsoft Excel spreadsheet templates. Less Frequent Collection CMMC certifications last up to three years. The assessment frequency for each level was determined by the DoD based on the sensitivity of information processed, stored, or transmitted by the OSA at each level. DoD Program Managers use the CMMC information in SPRS to confirm the validity status of an OSA's CMMC self-assessment or certification assessment prior to contract award. Rather than taking a contract-by-contract approach to securing Federal Contract Information (FCI) and Controlled Unclassified Information (CUI), the OSA may obtain multiple contracts with a single CMMC self-assessment or certification assessment, thereby reducing the cost to both DoD and industry. Consultation and Public Comments The Department consulted with members of the DIB Sector Coordinating Council (SCC), and government organizations including the DCMA DIBCAC and the Missile Defense Agency in determining

what data to collect in the CMMC instantiation of eMASS. The 60-Day Federal Register notice information is included in the preamble of the 32 CFR part 170 CMMC Program final rule for public comment.

A domestic or international business seeking a contract that contains DFARS clause 252.204-7012, and using a cloud service provider to process, store, or transmit covered defense information in performance of that DoD contract, must ensure that the CSP meets FedRAMP authorization or equivalency requirements. As the FedRAMP program and FedRAMP equivalency are available to international organizations, foreign entities do not need to develop their own FedRAMP program. FedRAMP authorization or equivalency is also available to small businesses. The DoD leverages the FedRAMP program to implement requirements for the adoption of secure cloud services across the Federal Government and provide a standardized approach to security and risk assessment for cloud technologies. Export controlled goods and ITAR are outside the scope of the 32 CFR part 170 CMMC Program rule. The process for identifying specific products or services that may meet NIST security requirements is beyond the scope of this rule. CMMC program requirements are unrelated to evaluation or approval of encryption or decryption products manufactured by foreign information security companies. DoD considered many alternatives before deciding upon the current CMMC structure. Alternative methods of assessment have proven inadequate and necessitated the establishment of CMMC. DoD declines to accept the recommendation of an alternate path to C3PAO accreditation. (printed page 83150) 27. Impact to Small Businesses a. Funding the CMMC Program Comment: One comment asserted that the rule does not address CMMC program funding, affordability, and sustainability. They recommended the DoD conduct and publish a comprehensive cost assessment for each level of CMMC certification and explore ways to reduce the financial burden on contractors. Response: DoD included an analysis of costs to meet CMMC requirements in the regulatory impact analysis for this rule. As described in the estimate included with the rule, the major cost categories for compliance with CMMC requirements are anticipated to include costs for completing a self-assessment (e.g., Level 1 or 2); costs to prepare for and undergo C3PAO assessment (Level 2); costs required to implement the Level 3 security requirements and for preparing to undergo DCMA DIBCAC assessment (Level 3). All of these except the market costs of a C3PAO are controlled by the organization seeking assessment. Market forces of supply and demand will determine C3PAO pricing for CMMC Level 2 certification assessments.

The Department quantitatively analyzes and monetizes the effect that this proposed rule would have on the actions of regulated entities to: conduct a Security Rule compliance audit; provide or obtain verification of business associates' compliance with technical safeguards; notify other regulated entities when workforce members' access to ePHI is altered or terminated; notify covered entities or business associates, as applicable, upon activation of a contingency plan; complete network segmentation; disable unused ports and remove extraneous software; deploy MFA and penetration testing; update health plan documents; update policies and procedures; update workforce training; and revise business associate agreements. The Department also quantitatively analyzes the effects on group health plan sponsors for ensuring that safeguards for their relevant electronic information systems meet Security Rule standards and notifying group health plans upon activation of the plan sponsors' contingency plans. Additionally, the Department quantitatively analyzes the benefits of the proposed modifications to regulated entities due to an expected reduction in costs of remediation of breaches and risk of breaches by regulated entities. The Department analyzes the remaining benefits and costs qualitatively because many of the proposed modifications are clarifications of existing requirements and predicting other concrete actions that such a diverse scope of regulated entities might take in response to this rule is inherently uncertain. Analytic Assumptions The Department bases its assumptions for calculating estimated costs and benefits on several publicly available datasets, including data from the U.S. Census Bureau (·Census·), the U.S. Department of Labor's (DOL) Bureau of Labor Statistics, the Small Business Administration (SBA), and the Department's Centers for Medicare & (printed page 995) Medicaid Services (CMS) and Agency for Healthcare Research and Quality (AHRQ). For the purposes of this analysis, the Department assumes that employee benefits plus indirect costs equal approximately 100 percent of pre-tax wages and adjusts the hourly wage rates by multiplying by two, for a fully loaded hourly wage rate. The Department adopts this as the estimate of the hourly value of time for changes in time use for on-the-job activities.

According to Blockchain for Access Control Systems, Executive Summary: Executive Summary Access control is concerned with determining the allowed activities of legitimate users and mediating every

attempt by a user to access a resource in the system. The objectives of an access control system are often described in terms of protecting system resources against inappropriate or undesired user access. From a business perspective, this objective could just as well be described in terms of the optimal sharing of information. As current information systems and network architectures evolve to be more lightweight, pervasive, and interactive - such as the cloud and Internet of Things (IoT) - there is need for an access control mechanism to support the requirements of decentralization, scalability, and trust for accessing objects, all of which are challenging for traditional mechanisms. Blockchains are tamper-evident and tamper-resistant cryptographically linked blocks of data (which create digital ledgers) implemented in a distributed fashion (i.e., without a central repository) and usually without a central authority (i.e., a bank, company, or government). It uses replicated, shared, and synchronized digital blocks between the users of a private or public distributed computer network located in different sites or organizations. Blockchain can be utilized for access control systems as a trustable alternative for a single entity/organization or a member of a large-scale system to enforce access control policies. The robust, distributed nature of blockchain technology can overcome the limitations of traditional access control systems in a decentralized and efficient way.

, (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) , (k)(4), and (k)(5). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would place the subject of an investigation on notice that they are under investigation and provide them with significant information concerning the nature of the investigation, thus resulting in a serious impediment to law enforcement investigations. (B) From subsections (d) and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because there is no necessity for such publication since the system of records will be exempt from the underlying duties to provide notification about and access to information in the system and to make amendments to and corrections of the information in the system. (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NSA will, nevertheless, continue to publish such a notice in broad generic terms, as is its current practice. (4) System identifier and name. GNSA 04, Military Reserve Personnel Data Base. (i) Exemption. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (B) Therefore, portions of this system may be exempt pursuant to

By design, the Security Rule sets a national floor for the security measures that regulated entities are required to implement to protect the confidentiality, integrity, and availability of ePHI. In 2003, the Department opted to frame the standards in terms that were as generic as possible and in a manner that enabled the standards to be met through various approaches or technologies to ensure that regulated entities had the flexibility to determine how best to protect the confidentiality, integrity, and availability of ePHI based on their specific circumstances. [262] When we extended the Security Rule in 2013 to directly apply to business associates in accordance with the HITECH Act, [263] the Department acknowledged that some business associates might not have engaged in the formal administrative safeguards required by the Security Rule, and we made it clear that business associates would be expected to do so going forward. [264] Despite the changes

in the health care environment between 2003 and 2013, the Department made minimal changes to the Security Rule at that time because we believed that the compliance obligations of regulated entities were clear and well-understood. In fact, when a commenter recommended that the Department remove the addressable designation from the Security Rule because it leads to ambiguity in the rule's application, we declined to do so at that time because we were concerned that it would reduce the rule's scalability and flexibility. [265] However, as we noted in 2003, the rule's flexibility of approach is primarily provided for in paragraph (b)(2) of 45 CFR 164.306 and in the standards themselves. [266] The addressability feature merely provided an added level of flexibility [267] in a way that the Department now believes is inadequate to ensure that regulated entities implement reasonable and appropriate security safeguards.

DFARS 252.204-7008 (Compliance with Safeguarding CDI Controls) Requires offerors to represent that they will implement NIST SP 800-171 security requirements. Non-compliance with 252.204-7008 can result in: loss of contract eligibility, termination for cause, False Claims Act liability (if contractor misrepresented compliance status), suspension or debarment from future DoD contracting, and in cases involving CUI spillage or breach, potential civil or criminal penalties.

According to ISCSMA_ An Information Security Continuous Monitoring Program Assessment, 4.2 ScoreSummary Worksheet: 4.2 ScoreSummary Worksheet The ScoreSummary worksheet in the principal assessment workbook, shown in Figure 25, provides the same view-based scoring output as shown in Figure 21 for assessment files. The scores in Figure 21 are based on a single workbook that contains a set of judgments for a single level, while the scores in Figure 25 are based on the consolidated judgments for the entire organization.

There are 954 Direct Health and Medical Insurance Carrier firms out of a total 5,822 Insurance Carrier firms, such that health and medical insurance firms make up approximately 16.4 percent of insurance firms [= 954/5,822]. [948] Also, according to Census data, there are 2,506 Third Party Administration of Insurance and Pension Funds firms and 8,375 establishments. This category also includes clearinghouses. The Department assumes that 16.4 percent of these firms service health and medical insurance because that is equivalent to the share of insurance firms that are health and medical. As a result, the Department estimates that 411 firms categorized as Third Party Administrators are affected by the proposals in this NPRM [= 2,506 × .164]. Similarly, the Department estimates that 1,374 associated establishments would be affected by the proposals in this NPRM [= 8,375 total establishments × .164]. Most of these are business associates. Based on data from the Department's HIPAA audits and experience administering the HIPAA Rules, we are aware of approximately 36 clearinghouses. See table 4 below. There were 56,289 community pharmacies, including 19,261 pharmacy and drug store firms, operating in the U.S. in 2023. [949] Small pharmacies generally use pharmacy services administration organizations (PSAOs) to provide administrative services, such as conducting negotiations. Based on information from industry, the Department estimates that the proposed rule would affect fewer than 10 PSAOs and we include this within the estimated 1 million business associates affected by the proposals in this NPRM. [950] The Department assumes that (printed page 996) costs affecting pharmacies are incurred at each pharmacy and drug store establishment and each PSAO. Table 4-Estimated Number, Type, and Size Threshold of Covered Entities

Covered Entities	NAICS code	Type of entity	Firms	Establishments
Small business administration (SBA) size threshold c (million)	524114	Health and Medical Insurance Carriers	954	5,552
	\$47 524292	Clearinghouses	a 36	36
	47 622	Hospitals	3,095	7,465
	47 446110	Pharmacies	b 31,671	56,289
	37.5 6211-6213	Office of Drs. & Other Professionals	429,476	527,951
	9-16 6215	Medical Diagnostic Laboratories & Imaging	8,714	19,477
	19-41.5 6214	Outpatient Care	26,084	54,642
	19-47 6219	Other Ambulatory Care	10,547	16,114
	20.5-40 623	Skilled Nursing & Residential Facilities	42,421	95,175
	16-34 6216	Home Health Agencies	27,433	38,040
	19 532283	Home Health Equipment Rental	488	1,859
	41	Total	580,919	822,600

a This North American Industry Classification System (NAICS) category includes clearinghouses and is titled Third Party Administration of Insurance and Pension Funds. The number of clearinghouses is based on the Department's research. b Number of pharmacies is taken from industry statistics. c See Table of Small Business Size Standards, U.S. Small Business Administration (Mar. 17, 2023), https://www.sba.gov/sites/sbagov/files/2023-06/2023-06-Table%20of%20Size%20Standards_Effective%20March%2017%2C%202023%20%282%29.pdf.

(7) Inspector General investigative files and action request/complaint files (records in system notice A0021-1 SAIG, Inspector General Records) have been exempted from the amendment provisions of

the Privacy Act. Requests to amend these reports will be considered under AR 20-1 by The Inspector General. Action by the The Inspector General will constitute final action on behalf of the Secretary of the Army under that regulation. (8) Other records that are exempt from the amendment provisions of the Privacy Act are listed in the applicable PA system of records notices. (c) Amendment procedures. (1) Requests to amend records should be addressed to the custodian or system manager of the records. The request must reasonably describe the records to be amended and the changes sought (e.g. , deletion, addition, or amendment). The burden of proof is on the requester. The system manager or records custodian will provide the individual with a written acknowledgment of the request within 10 working days and will make a final response within 30 working days of the date the request was received. The acknowledgment must clearly identify the request and inform the individual that final action will be forthcoming within 30 working days. (2) Records for which amendment is sought must be reviewed by the proper system manager or custodian for accuracy, relevance, timeliness, and completeness. (3) If the amendment is appropriate, the system manager or custodian will physically amend the records accordingly. The requester will be notified of such action. (4) If the amendment is not warranted, the request and all relevant documents, including reasons for not amending, will be forwarded to the proper Denial Authority within 10 working days to ensure that the 30 day time limit for the final response is met. In addition, the requester will be notified of the referral. (5) Based on the documentation provided, the Denial Authority will either amend the records and notify the requester and the custodian of the records of all actions taken, or deny the request. If the records are amended, those who have received the records in the past will receive notice of the amendment. (6) If the Denial Authority determines that the amendment is not warranted, he or she will provide the requester and the custodian of the records reason(s) for not amending. In addition, the Denial Authority will send the requester an explanation regarding his or her right to seek further review by the DA Privacy Act Review Board, through the Denial Authority, and the right to file a concise ·Statement of Disagreement· to append to the individual's records. (i) On receipt of a request for further review by the Privacy Act Review Board, the Denial Authority will append any additional records or background information that substantiates the refusal or renders the case complete; (ii) Within 5 working days of receipt, forward the appeal to the DA Privacy Act Review Board; and

One comment noted the terms ·data·, ·technical data·, and ·information· are used synonymously throughout the rule and supplemental documents. They also noted that neither NARA's CUI Registry nor the NIST SP 800-171 R2 define the word ·information· and asserted this was a major oversight by NARA ISOO, the CUI Program Executive Agent. The commenter requested this rule adopt the term ·Information· throughout the rule and only use ·data· when specifically intended based on its definition. Another commenter requested the term ·Technical Data· be replaced with the term ·Information·. Response: As a commenter stated, both the CUI program and NIST use the term ·information·. Suggestions that the DoD work with NARA or NIST to define this term are outside the scope of this rule. Within this rule, data generally refers to individual facts, such as those submitted to eMASS or SPRS; however, data and information may be used interchangeably. DoD declined to make requested administrative edits because they would not result in a substantive change. j. Source Materials Incorporated by Reference Comment: Four comments asked for clarification of those documents incorporated by reference, or the specific versions of documents referenced in the rule. Response: The DoD declined to incorporate by reference the Department's role as data owner. NIST SP 800-53 R5 was incorporated by reference only for use with applicable definitions because it provided the latest definitions available. The OSA is responsible for determining its CMMC Assessment Scope and its relationship to security domains. Assets are out-of-scope when (printed page 83163) they are physically or logically separated from the assessment scope. Contractor Risk Managed Assets are only applicable within the OSA's assessment scope. Table 3 to §170.19(c)(1) is used to identify the asset categories within the assessment scope and the associated requirements for each asset category. Contractor's risk-based security policies, procedures, and practices are not used to define the scope of the assessment, they are descriptive of the types of documents an assessor will use to meet the CMMC assessment requirements. To ensure the source of every definition is accounted for, the terms in §170.4 either cite a reference or are designated as CMMC-custom using the notation ·(CMMC-custom term)·. The rule has been updated to eliminate the CNSS Glossary definitions and replaced them with appropriate NIST definitions. k. Miscellaneous Other Terms, References and Notations Comment: Three comments asked about references to the DoD Manual 8570, ·Information Assurance Workforce Improvement Program·, and one asked if the references should be replaced by the newer DoD Manual 8140. One commenter suggested DoD add an enhanced definition of ·Security Domain· domain to the glossary.

§ 286.25 Collection of fees and fee rates. (a) Collection of fees. Collection of fees will be made at the time of providing the documents to the requester or recipient when the requester specifically states the costs involved shall be acceptable or acceptable up to a specified limit that covers the anticipated costs. (b) Fees for search time. (1) Manual search fees. This table shows FOIA hourly processing fees. Type Grade Hourly rate (\$) Clerical E9/GS8 and below/NSPS pay band 1 27.00 Professional O1-O6/W01-05/GS9-GS15/NSPS pay bands 2 and 3 53.00 Executive O7/GS16/SES and above 108.00 Contractor 53.00 (2) Computer search. Fee assessments for computer search consists of 2 parts; individual time (hereafter referred to as human time), and machine time. (i) Human time. Human time is all the time spent by humans performing the necessary tasks to prepare the job for a machine to execute the run command. This includes the time spent to create a program to extract specific fields out of a database. If execution of a run requires monitoring by a human, that human time may be also assessed as computer search. The terms programmer/operator shall not be limited to the traditional programmers or operators. Rather, the terms shall be interpreted in their broadest sense to incorporate any human involved in performing the computer job (e.g., technician, administrative support, operator, programmer, database administrator, or action officer). (ii) Machine time. Machine time involves only direct costs of the Central Processing Unit (CPU), input/output devices, and memory capacity used in the actual computer configuration. Only this CPU rate shall be charged. No other machine related costs shall be charged. In situations where the capability does not exist to calculate CPU time, no machine costs can be passed on to the requester. When CPU calculations are not available, only human time costs shall be assessed to requesters. Should the DoD Components lease computers, the services charged by the lessor shall not be passed to the requester under the FOIA. (c) Duplication. This table shows duplication costs. (printed page 71866) Type Cost per page (cents) Pre-Printed material 02. Office copy 15. Microfiche 25. Computer copies (tapes, discs or printouts) Actual cost of duplicating the tape, disc or printout (includes operator's time and cost of the medium). (d) Review Fees. See paragraph (b)(1) of this section. (e) Audiovisual documentary materials. Search costs are computed as for any other record. Duplication cost is the actual direct cost of reproducing the material, including the wage of the person doing the work. If the duplication is performed by a contractor, then the actual cost charged to the government by the contractor is passed on to the requester. Audiovisual materials provided to a requester need not be in reproducible format or quality. (f) Other records.

(1) Includes: (i) All products of data compilation made or received by an agency of the U.S. Government under Federal law in connection with the transaction of public business and in DoD possession and control at the time the search in response to a FOIA request is made. Examples include books, papers, maps, photographs, machine-readable materials inclusive of those in electronic form or format, and other documentary materials, regardless of physical form or characteristics. (ii) Research data produced under a Federal grant used by the Federal Government in developing an agency action that has the force and effect of law (Office of Management and Budget Circular (OMB) A-110). (2) Does not include: (i) Objects or articles, such as structures, furniture, vehicles, and equipment, whatever their historical or evidentiary value. (ii) Anything that is not a tangible or documentary record, such as an individual's memory or an oral communication. (iii) Personal records of an individual not subject to agency creation or retention requirements, created and maintained primarily for the convenience of an agency employee and not distributed to other agency employees for their official use. Personal papers fall into three categories: (A) Those created before entering Government service. (B) Private materials brought into, created, or received in the office that were not created or received in the course of transacting Government business. (C) Work-related personal papers that are not used in the transaction of Government business. (iv) A record that is not in the possession and control of the Department of Defense when the search is conducted in response to a FOIA request. (There is no obligation to create, compile, or obtain a record to satisfy a FOIA request.) Appellate authority. The Head of the DoD Component, or designee, having jurisdiction to review and possibly reverse or amend any adverse determination by an IDA. Direct costs. Those expenditures the DoD Component makes in searching for, reviewing, and duplicating documents to respond to a FOIA request. Direct costs include, for example, the salary of the employee performing the work (the basic rate of pay plus 16 percent of that rate to cover benefits) and the costs of operating duplicating machinery. (These factors have been included in the fee rates prescribed at § 286.25. Not included in direct costs are overhead expenses such as the cost of space, heating, or lighting the facility in which the records are stored. Electronic records. Records (including e-mail) created, stored, and

retrievable by electronic means. Federal agency. Defined in 5 U.S.C. 551(1) and 552(f)(1). (A Federal agency cannot make FOIA requests.) FOIA office. The DoD Component office that receives FOIA requests from and responds directly to the public. FOIA public liaison. Defined in E.O. 13392. FOIA request.

CIS Control 16 · Application Software Security Manage the security life cycle of in-house developed, hosted, or acquired software to prevent, detect, and remediate security weaknesses before they can impact the enterprise. Applications provide a human-friendly interface to allow users to access and manage data in a way that is aligned to business functions. They also minimize the need for users to deal directly with complex (and potentially error-prone) system functions, like logging into a database to insert or modify files. Enterprises use applications to manage their most sensitive data and control access to system resources, and so an attacker can use the application itself to compromise the data, instead of an elaborate network and system hacking sequence, attempting to bypass network security controls and sensors. This is why protecting user credentials (specifically application credentials), defined in CIS Control 6, is so important. Applications provide a human-friendly interface to allow users to access and manage data in a way that is aligned to business functions. They also minimize the need for users to deal directly with complex (and potentially error-prone) system functions, like logging into a database to insert or modify files. Enterprises use applications to manage their most sensitive data and control access to system resources, and so an attacker can use the application itself to compromise the data, instead of an elaborate network and system hacking sequence, attempting to bypass network security controls and sensors. This is why protecting user credentials (specifically application credentials), defined in CIS Control 6, is so important. Lacking credentials, application flaws are the attack vector of choice. However, today's applications are developed, operated, and maintained in a highly complex, diverse, and dynamic environment. Applications run on multiple platforms; web, mobile, cloud, etc., with application architectures that are more complex than legacy client-server or database-web server structures. Development life cycles have become shorter, transitioning from months or years in long waterfall methodologies, to DevOps cycles with frequent code updates. Also, applications are rarely created from scratch, and are often assembled from a complex mix of development frameworks, libraries, existing code, and new code. There are also modern and evolving data protection regulations dealing with user privacy. These may require compliance to regional or sector-specific data protection requirements. These factors make traditional approaches to security, like control (of processes, code sources, run-time environment, etc.), inspection, and testing, much more challenging. Also, the risk that an application vulnerability introduces might not be understood, except in a specific operational setting or context. Application vulnerabilities can be present for many reasons; insecure design, insecure infrastructure, coding mistakes, weak authentication, and failure to test for unusual or unexpected conditions. Attackers can exploit specific vulnerabilities, including buffer overflows, exposure to Structured Query Language (SQL) injection, cross-site scripting, cross-site request forgery, and click-jacking of code to gain access to sensitive data, or take control over vulnerable assets within the infrastructure as a launching point for further attacks. Applications and websites can also be used to harvest credentials, data, or attempt to install malware onto the users who access them. Finally, it is now more common to acquire Software as a Service (SaaS) platforms, where software is developed and managed entirely through a third-party. These might be hosted anywhere in the world. This brings challenges to enterprises who need to know what risks they are accepting with using these platforms; and they often do not have visibility into the development and application security practices of these platforms. Some of these SaaS platforms allow for customizing of their interfaces and databases. Enterprises who extend these applications should follow this CIS Control, similar to if they were doing ground-up customer development.

From the NIST SP 800-172 Rev 3 Final Public Draft: · Cyber resiliency: The ability to anticipate, withstand, recover from, and adapt to adverse conditions, stresses, attacks, or compromises on systems that use or are enabled by cyber resources. Cyber resiliency is intended to enable organizational missions or business objectives that depend on cyber resources to be achieved in a contested cyber environment. This strategy recognizes that the APT may find ways to compromise established defenses despite the best safeguards implemented by organizations. When this occurs, organizations must have access to additional safeguards to detect, outmaneuver, confuse, deceive, mislead, and impede the adversary—that is, removing the adversary's tactical advantage and protecting the organization's critical programs and high value assets.

(1) If the CSA determines the parent must be processed for an entity eligibility determination, then the parent must have an entity eligibility determination at the same or higher level as the subsidiary. (2) When a parent and subsidiary or multiple cleared subsidiaries are collocated, a formal written agreement to use common security services may be executed by the entities, subject to the approval of the CSA. (k) Joint ventures. A joint venture may be granted eligibility for access to classified information if it meets the eligibility requirements in paragraph (c) of this section, including: (1) The joint venture must be established as a legal business entity (e.g. limited liability company, corporation, or partnership). A joint venture established by contract that is not also established as a legal business entity is not eligible for an entity eligibility determination. (2) The business entity operating as a joint venture must have been awarded a classified contract or sponsored by a GCA or prime contractor for an entity eligibility determination in advance of a potential award for which the business entity has bid pursuant to paragraph (c) of this section. (3) The business entity operating as a joint venture must have an employee or employees appointed as security officials or KMP pursuant to § 117.7(b). (l) Consultants. The responsible CSA will determine when there is a need for self-employed consultants requiring access to classified information to be considered for an entity eligibility determination. (m) Limited entity eligibility determination (Non-FOCI). (1) The applicable CSA may choose to allow a GCA to request limited entity eligibility determinations for a single, narrowly defined contract, agreement, or circumstance and specific to the requesting GCA's classified information. This is not the same as a limited entity eligibility determination in situations involving FOCI, when the FOCI is not mitigated or negated. (i) Limited entity eligibility determinations (or FCLs) involving FOCI will be processed in accordance with § 117.11(e). (ii) This paragraph (paragraph (m) of this section) applies to limited entity eligibility determinations for purposes other than FOCI mitigation in accordance with 32 CFR part 2004 . Additional guidance may be provided by the responsible CSA. (2) An entity must be sponsored for a limited entity eligibility determination by a GCA in accordance with the sponsorship requirements contained in paragraph (c) of this section. The contractor should be aware that the sponsorship request from the GCA to the CSA must also include: (i) Description of the compelling need for the limited entity eligibility determination that is in accordance with U.S. national security interests. (ii) Specific reason(s) or rationale for limiting the entity eligibility determination. (iii) The GCA's formal acknowledgement and acceptance of the risk associated with this rationale.

983. For this analysis, a record is the ePHI of one individual. Back to Citation 984. See Annual Report to Congress on Breaches of Unsecured Protected Health Information for Calendar Year 2022, supra note 213, p. 9 (2023); December 2023 Healthcare Data Breach Report, supra note 960 . Back to Citation 985. The break-even calculations presented here only include regulated entities because breach data is not available for health plan sponsors. Including sponsors and assuming they have the same rate of breaches would result in a similar break-even point in terms of percent decrease from baseline. Back to Citation 986. Cybersecurity Performance Goals, supra note 18. Back to Citation 987. Id. Back to Citation 988. According to the 2021 Verizon Data Breach Investigations Report, phishing was present in 36% of breaches (up from 25% last year); [and] 23% of malware was delivered through email. See Technical Volume 2: Cybersecurity Practices for Medium and Large Healthcare Organizations, Cybersecurity Practice #1: Email Protection Systems, HHS Healthcare & Public Health Sector Coordinating Council, p. 13 (2023), <https://405d.hhs.gov/Documents/tech-vol2-508.pdf> (citing a 2021 Verizon Data Breach Investigations Report). Back to Citation 989. See proposed 45 CFR 164.312(b)(2) and (g) . Back to Citation 990. See Individuals' Right under HIPAA to Access their Health Information 45 CFR 164.524 , What is the liability of a covered entity in responding to an individual's access request to send the individual's PHI to a third party?, Office for Civil Rights, U.S. Department of Health and Human Services, <https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/access/index.html> . Back to Citation 991. 42 U.S.C. 1320d-2(d)(1)(A)(v) . Back to Citation 992. Public Law 113-283 (Dec. 18, 2014) (codified at 44 U.S.C. 3551 et seq.). Back to Citation 993. Id. Back to Citation 994. 45 CFR 164.304 (definition of Information system). Back to Citation 995. Managing Information as a Strategic Resource, Circular No. A-130, Management of Federal Information Resources, Appendix III, Security of Federal Automated Information Resources, Office of Management and Budget, Executive Office of the President (Feb. 8, 1996), <https://georgewbush-whitehouse.archives.gov/omb/circulars/a130/a130.html> . Back to Citation 996. Public Law 104-13 , 109 Stat. 166 (May 22, 1995) (codified at 44 U.S.C. 3502(8)) (definition of information system); see also Managing Information as a Strategic Resource, Circular No.

A-130, Office of Management and Budget, Executive Office of the President, p. 31 (Jul. 28, 2016), (definition of "information system") https://www.whitehouse.gov/wp-content/uploads/legacy_drupal_files/omb/circulars/A130/a130revised.pdf . Back to Citation 997. "Proposed 45 CFR 164.312(f)(2)(ii) . Back to Citation 998. 45 CFR 164.304 (proposed definition of "Multi-factor authentication"). Back to Citation 999. 740,348 = 822,609 covered entities × .90.

(d) Nondefense agencies that have industrial security services agreements with DoD, and DoD components, shall use the DD Form 254, Contract Security Classification Specification, to provide security classification guidance to U.S. contractors, and subcontractors as applicable, requiring access to information classified as "Confidential", "Secret", or "Top Secret". (1) Provided that the data submittal is unclassified, the DD Form 254 shall be completed electronically in the NISP Contract Classification System (NCCS), which is accessible via the Procurement Integrated Enterprise Environment (PIEE) at <https://wawf.eb.mil> . Nondefense agencies with an existing DD Form 254 information system may use that system. (2)(i) A contractor, or subcontractor (if applicable), requiring access to classified information under a contract shall be identified with a Commercial and Government Entity (CAGE) code on the DD Form 254 (see subpart 4.18 for information on obtaining and validating CAGE codes). (ii) Each location of contractor or subcontractor performance listed on the DD Form 254 is required to reflect a corresponding unique CAGE code for each listed location unless the work is being performed at a Government facility, in which case the agency location code shall be used. Each subcontractor location requiring access to classified information must be listed on the DD Form 254. (iii) Contractor and subcontractor performance locations listed on the DD Form 254 are not required to be separately registered in the System for Award Management (SAM) solely for the purposes of a DD Form 254 (see subpart 4.11 for information on registering in SAM). * * * *

* 5. Amend section 4.403 by removing from paragraph (c) introductory text "contract as follows" and adding "contract as identified in the requirement documentation as follows" in its place, and revising paragraph (c)(1) to read as follows: 4.403 Responsibilities of contracting officers. * * * * (c) * * * (1) Nondefense agencies that have industrial security services agreements with DoD, and DoD components, shall use the Contract Security Classification Specification, DD Form 254. The contracting officer, or authorized agency representative, is the approving official for the DD Form 254 associated with the prime contract and shall ensure the DD Form 254 is properly prepared, distributed by and coordinated with requirements and security personnel in accordance with agency procedures, see 4.402(d)(1). * * * * 4.1801 [Amended] 6. Amend section 4.1801 by removing the defined term "Commercial and Government Entity (CAGE) code". PART 52 SOLICITATION PROVISIONS AND CONTRACT CLAUSES 7. Amend section 52.204-16 by: a. Revising the date of the provision; b. Removing from the end of paragraph (a)(1) "entity; or" and adding "entity by unique location; or" in its place; c. Revising paragraph (b); d. In paragraph (c)(2) removing the word "offeror" and adding "Offeror" in its places; e. Revising paragraph (e); and f. Adding paragraph (g).

"System Owner" "Mission or Business Owner" "Chief Information Officer" "System Security Officer" "System Privacy Officer" NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

APPENDIX E PAGE 130 This publication is available free of charge from:

<https://doi.org/10.6028/NIST.SP.800-37r2> TABLE E-2: CATEGORIZATION TASKS, RESPONSIBILITIES, AND SUPPORTING ROLES RMF TASKS PRIMARY RESPONSIBILITY SUPPORTING ROLES TASK C-1 System Description Document the characteristics of the system. System Owner "Authorizing Official or Authorizing Official Designated Representative" "Information Owner or Steward" "System Security Officer" "System Privacy Officer" TASK C-2 Security Categorization Categorize the system and document the security categorization results. "System Owner" "Information Owner or Steward" "Senior Accountable Official for Risk Management or Risk Executive (Function)" "Chief Information Officer" "Senior Agency Information Security Officer" "Authorizing Official or Authorizing Official Designated Representative" "System Security Officer" "System Privacy Officer" TASK C-3 Security Categorization Review and Approval Review and approve the security categorization results and decision. "Authorizing Official or Authorizing Official Designated Representative" "Senior Agency Official for Privacy (for systems processing PII)" "Senior Accountable Official for Risk Management or Risk Executive (Function)" "Chief Information Officer" "Senior Agency Information Security Officer"

- SP 800-137A, Assessing Information Security Continuous Monitoring Programs [1] - The NIST Cybersecurity Framework (CSF) 2.0 [2] - SP 800-30r1 (Revision 1), Guide for Conducting Risk Assessments [3] - SP 800-37r2, Risk Management Framework for Information Security Systems and Organizations: A System Life Cycle Approach for Security and Privacy [4] - SP 800-161r1, Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations [5] - Internal Report (IR) 8286, Identifying and Estimating Cybersecurity Risk for Enterprise Risk Management (ERM) [6] Data from various sources (e.g., vulnerability scans, incident logs, and compliance assessments) can be aggregated to help executives understand information security. Summarizing measurement findings and metrics into concise reports facilitates efficient communication. Regularly reporting on measurement and assessment results fosters transparency, promotes accountability for meeting performance targets, and encourages continuous improvements. Sharing findings with executives demonstrates the organization's commitment to its information security posture. Stakeholder interests may be determined through multiple venues, such as interviews, brainstorming sessions, mission statement reviews, in-house knowledge, and existing findings from risk assessments. There may also be laws and regulations that the organization may need to consider. Input from those who interact with individual systems and existing system-level data will provide targeted insight into the measurement needs of an organization. Ideally, stakeholder interests will be reviewed periodically during the ongoing work of the information security measurement program.

(F) From subsection (e)(3) because the requirement that individuals supplying information be provided with a form stating the requirements of subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (G) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (H) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (I) From subsection (e)(8) because the individual notice requirements of subsection (e)(8) could present a serious impediment to law enforcement as this could interfere with the ability to issue search authorizations and could reveal investigative techniques and procedures. (J) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (K) From subsection (g) because portions of this system of records are compiled for law enforcement purposes and have been exempted from the access provisions of subsections (d) and (f). (21) System identifier and name. A0340-21 OAA, Privacy Case Files. (i) Exemption. During the processing of a Privacy Act request (which may include access requests, amendment requests, and requests for review for (printed page 14756) initial denials of such requests), exempt materials from other systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those 'other' systems of records are entered into this system, the Department of the Army hereby claims the same exemptions. (ii) Authority. 5 U.S.C. 552a(j)(2) , and (k)(1) through (k)(7) . (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a

Amend section 4.1801 by removing the term 'Commercial and Government Entity (CAGE) code'. 7. Amend section 4.1802 by revising the paragraph (a) introductory text to read as follows: 4.1802 Policy (a) Commercial and Government Entity (CAGE) code. * * * * * 8. Amend section 4.1804 by revising paragraphs (a) and (c) to read as follows: 4.1804 Solicitation provisions and contract clause. (a)(1) Insert the provision at 52.204-16, Commercial and Government Entity Code Reporting, in all solicitations that include: (i) 52.204-6, Unique Entity Identifier; or (ii) 52.204-7, System for Award Management. (2) Use the provision with its Alternate I when the clause 52.204-2, Security Requirements, is used. * * * * * (c) (1) Insert the clause at 52.204-18, Commercial and Government Entity Code Maintenance in all solicitations and contracts when the solicitation contains the provision at 52.204-16, Commercial and Government Entity Code Reporting. (2) Use the clause with its Alternate I when the provision 52.204-16, Commercial and Government Entity Code Reporting, is used with its Alternate I. * * * * * PART 52-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 9. Amend section 52.204-16 by: a. Revising the date of the provision; b. Removing from the end of paragraph (a)(1) 'entity; or' and adding 'entity by unique location; or' in its place; c. Revising paragraph (b) and (c)(1); d. Removing from paragraph (c)(2) 'offeror' twice and adding 'Offeror' in their places, respectively; e. Removing from paragraph (c)(3) 'NSPA' and adding 'NATO Support and Procurement Agency (NSPA)' in its place; f. Removing from paragraph

(e) ·Code· three times and adding ·code· in their places, respectively; and g. Adding an Alternate I. The revisions and addition read as follows: 52.204-16 Commercial and Government Entity Code Reporting. * * * * * Commercial and Government Entity Code Reporting ([DATE]) * * * *

* (b) The Offeror shall provide its CAGE code with its offer with its name and address or otherwise include it prominently in its proposal. The CAGE code must be for that name and address. Insert the word ·CAGE· before the number. The CAGE code is required prior to award. (c) * * * (1) Registration in the System for Award Management (SAM) at www.sam.gov . If the Offeror is located in the United States or its outlying areas and does not already have a CAGE code assigned, the Defense Logistics Agency (DLA) Commercial and Government Entity (CAGE) Branch will assign a CAGE code as a part of the SAM registration process. SAM registrants located outside the United States and its outlying areas shall obtain a North Atlantic Treaty Organization (NATO) CAGE (NCAGE) code prior to registration in SAM (see paragraph (c)(3) of this provision). * * * * * Alternate I ([DATE]). As prescribed at 4.1804(a), add the following additional paragraph (g).

The resulting tailored baseline set of security controls and the supporting rationale for the selection decisions (including any information system use restrictions required by organizations) are documented in system security plans. Documenting significant risk management decisions in the security control selection process is imperative so that authorizing officials have access to necessary information to make informed authorization decisions for organizational information systems, as demonstrated in Figure 3.

As another example, based on OCR's investigation experience, some regulated entities are not developing and implementing compliant response plans for security incidents, including those that are breaches of unsecured ePHI under the Breach Notification Rule. Section 164.308(a)(6)(i) establishes the standard that requires regulated entities to implement policies and procedures to address security incidents, while 45 CFR 164.308(a)(6)(ii) includes the implementation specifications for that standard. This requirement, included in the 2003 Final Rule, aligns with the NIST Cybersecurity Framework version 2.0 requirement for incident management. [254] Similarly, NIST Cybersecurity Framework version 1.1 recommended the execution and maintenance of response processes and procedures to ensure response to detected cybersecurity incidents. [255] And yet, when OCR investigates the circumstances surrounding breach reports, OCR continues to find evidence that regulated entities have not implemented policies and procedures to detect and respond to security incidents, leading to significant time lapses between a ·successful· security incident [256] and discovery of, and response to, the security incident. [257] Thus, based on the OCR's experience investigating and enforcing the Security Rule, the Department believes that many regulated entities would benefit from additional instruction in regulatory text regarding their compliance obligations to determine how to select security (printed page 916) measures that are reasonable and appropriate for their circumstances. We are also concerned that recent caselaw has not accurately set forth the steps regulated entities must take to adequately protect the confidentiality, integrity, and availability of ePHI, as required by the statute. Specifically, in the *University of Texas M.D. Anderson Cancer Center v. HHS* (· M.D. Anderson ·), the U.S. Court of Appeals for the Fifth Circuit held, among other things, that the Security Rule does not say anything about how effective a mechanism for encryption must be, nor does it require that an encryption mechanism provide ·bulletproof protection· of all systems containing ePHI. [258] Thus, under the court's interpretation, a regulated entity can meet its obligations under the Security Rule concerning encryption and decryption of ePHI by implementing a mechanism to do so, without regard for the effectiveness of the implementation. [259] Additionally, the court noted that the requirement for ·a mechanism· does not ·prohibit a [regulated] entity from creating `a mechanism' by directing employees to sign an [agreement] that requires the encryption of portable devices.· [260]

Three comments recommended that the DoD or CMMC PMO have a role in the assessment appeals process. Of these, one cited the DFARS clause 252.204-7012 clause as precedent for DoD CIO to render final decisions. Some commenters suggested the CMMC AB relationship to C3PAOs would bias any decisions they may make, and that final appeal authority is an inherently governmental risk acceptance decision. One comment suggested that the DIBCAC or other DoD entity render final appeals decisions or take responsibility for certifying OSCs. They also asked for the C3PAOs to be released from liability for reasonable assessment judgments. Two comments asked whether the only means to appeal a CMMC AB final decision is through litigation. Another comment asked who could escalate an appeal to the CMMC AB. One comment requested the rule include more requirements for the C3PAO appeals process,

including that the process be time bound and address disputes related to perceived assessor errors, malfeasance, and unethical conduct, while another comment requested a simpler appeals process. One comment requested clarification as to how the OSC interfaces with the C3PAO for appeals purposes. One comment asked if there was a process to challenge C3PAOs' findings of non-compliance if additional requirements are applied from an assessment guide that are not included in the source standard. One comment asked how to dispute the specific CMMC level included in a solicitation. Response: Requirements for CMMC Conditional certification assessments for each level are defined in §§ 170.16 through 170.18. Section 170.6(e) describes indications that may trigger investigative evaluations of an OSA's CMMC Status. The DoD has revised the rule throughout to delete the term 'revocation' and to clarify that the DoD reserves its right to conduct a DCMA DIBCAC assessment of the OSA, as permitted under DFARS clause 252.204-7012 and DFARS clause 252.204-7020. If the results of a subsequent DIBCAC assessment show that adherence to provisions of this rule have not been achieved or maintained, the DIBCAC results take precedence over any pre-existing CMMC self-assessment(s) or Final certification assessment(s) and will result in SPRS reflecting that the OSA is not in compliance (i.e., lacks a current Certificate of CMMC Status). There are no additional requirements or checks on self-assessments to ensure that OSAs maintain the SSP and conduct self-assessments correctly, beyond those identified in the rule.

, by clarifying that procedures must be written. We also propose to redesignate the implementation specification for testing and revision procedures as paragraph (a)(13)(ii)(F) and to clarify that procedures for testing and revising of the required contingency plans must be established in writing. We propose to require a regulated entity to review and implement its procedures for testing contingency plans at least once every 12 months, to document the results of such tests, and to modify those plans as reasonable and appropriate based on the results of those tests. p. Section 164.308(a)(14) Standard: Compliance Audit The final standard we propose under 45 CFR 164.308(a) is a new standard for compliance audits at proposed 45 CFR 164.308(a)(14) . For this proposed standard, the Department proposes to require regulated entities to perform and document an audit of their compliance with each standard and implementation specification of the Security Rule at least once every 12 months. While the Security Rule does not currently require regulated entities to conduct internal or third-party compliance audits, such activities are important components of a robust cybersecurity program. The Government Accountability Office has published guidance on conducting cybersecurity performance audits for Federal agencies. [612] Audits are typically conducted independently from information security management, and the function generally reports to the governing body of the regulated entity. This independence can provide an objective view of the regulated entity's policies and practices. According to the Institute of Internal Auditors, an internal audit provides '[i]ndependent and objective assurance and advice on all matters related to the achievement of objectives.' [613] An internal audit may be conducted by a business associate of a covered entity or a subcontractor of a business associate. These activities provide regulated entities with confidence in the effectiveness of their risk management plan. Thus, we believe that this proposal would aid a regulated entity in ensuring compliance with the Security Rule, and ultimately, protecting ePHI. We do not propose to specify whether the compliance audit should be performed by the regulated entity or an external party. [614] (printed page 956) q. Section 164.308(b)(1) and (2) Standard: Business Associate Contracts and Other Arrangements Vendor management and identification of risks in a supply chain are essential to controlling the introduction of new threats and risks to a regulated entity. [615] NIST guidance explains that regulated entities, are permitted to include more stringent cybersecurity measures in business associate agreements than those required by the Security Rule. [616] Such requirements would need to be agreed upon by both parties to the business associate agreement. [617]

From the NIST SP 800-172 Rev 3 Final Public Draft: Available at <https://www.govinfo.gov/app/details/USCODE-2017-title40/USCODE-2017-title40-subtitleIII-chap113-subchapIII-sec11331> NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 [25] Title 44 U.S. Code, Sec. 3502, Definitions. 2017 ed. Available at 2715 <https://www.govinfo.gov/app/details/USCODE-2021-title44/USCODE-2021-title44-chap35-subchapI-sec3502> [26] National Institute of Standards and Technology (2019) Roots of Trust Project. Available at <https://csrc.nist.gov/projects/hardware-roots-of-trust> NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 Appendix A. Acronyms 2720 APT Advanced Persistent Threat ASLR Address Space Layout Randomization BIOS Basic

ionally, there was an Inspectors General panel briefing on FISMA implementation and a panel of Chief Information Security Officers discussing their experiences with the accreditation process. The membership of the Board consists of 12 individuals and a Chairperson. The Director of NIST approves membership appointments and appoints the Chairperson. Each Board member serves for a four-year term. The Board's membership draws from experience at all levels of information security and privacy work. The members' careers cover government, industry, and academia. Members have worked in the Executive and Legislative branches of the federal government, civil service, senior executive service, the military, some of the largest corporations worldwide, small and medium-size businesses, and some of the top universities in the nation. The members' experience, likewise, covers a broad spectrum of activities including many different engineering disciplines, computer programming, systems analysis, mathematics, management positions, information technology auditing, legal experience, an extensive history of professional publications, and professional journalism. Members have worked (and in many cases, continue to work in their full-time jobs) on the development and evolution of some of the most important pieces of information security and privacy legislation in the federal government, including the Privacy Act of 1974, the Computer Security Act of 1987, the E-Government Act (including FISMA), and numerous e-government services and initiatives.

The Protect Function supports the ability to limit or contain the impact of a potential cybersecurity event. Examples of outcome Categories within this Function include: Access Control; Awareness and Training; Data Security; Information Protection Processes and Procedures; Maintenance; and Protective Technology.

- Risk Management Process - Organizational cybersecurity risk management practices are not formalized, and risk is managed in an ad hoc and sometimes reactive manner. Prioritization of cybersecurity activities may not be directly informed by organizational risk objectives, the threat environment, or business/mission requirements.
- Integrated Risk Management Program - There is limited awareness of cybersecurity risk at the organizational level and an organization-wide approach to managing cybersecurity risk has not been established. The organization implements cybersecurity risk management on an irregular, case-by-case basis due to varied experience or information gained from outside sources. The organization may not have processes that enable cybersecurity information to be shared within the organization.
- External Participation - An organization may not have the processes in place to participate in coordination or collaboration with other entities.
- Risk Management Process - Risk management practices are approved by management but may not be established as organizational-wide policy. Prioritization of cybersecurity activities is directly informed by organizational risk objectives, the threat environment, or business/mission requirements.
- Integrated Risk Management Program - There is an awareness of cybersecurity risk at the organizational level but an organization-wide approach to managing cybersecurity risk has not been established. Risk-informed, management-approved processes and procedures are defined and implemented, and staff has adequate resources to perform their cybersecurity duties.

about addressable implementation specifications and the notable changes in the environment in which health care is provided, we are concerned that some regulated entities proceed as if compliance with an addressable implementation specification is optional and that where there is an addressable implementation specification, that compliance with the relevant standard is also optional. That interpretation is incorrect and weakens the cybersecurity posture of regulated entities. We believe that compliance with the implementation specifications currently designated as addressable is not and should not be optional, particularly in light of the shift to an interconnected and cloud-based environment and a significant increase in the number of breaches of unsecured PHI from both internal and external actors, regardless of the regulated entity's specific circumstances. Thus, we believe that it is necessary to strengthen the Security Rule to reflect the changes in the health care environment and the evolution of (printed page 918) technology and to underscore that compliance with all of our proposals, if finalized, is required.

3. A Strengthened Security Rule Would Continue To Be Flexible and Scalable While Providing Regulated Entities With Greater Clarity

The Security Rule's fundamental flexibility and scalability generally would remain should the proposals in this NPRM be adopted. However, we are proposing to reduce that flexibility to better strengthen protections and address the changed nature of the environment in which health care is provided. The Department is also proposing in this NPRM to strengthen the Security Rule by providing greater clarity regarding the nature of its flexibility and scalability and the Department's expectations, as requested by regulated entities and other stakeholders. In fact, in response to a request for information published in 2022, [284] several commenters urged the Department to propose regulations that establish a single set of clear standards for regulated entities, raise the

floor for security requirements and expectations, and encourage regulated entities to safeguard ePHI while maintaining flexibility and scalability. Commenters also encouraged the Department to rely on commonly available, non-proprietary frameworks that allow regulated entities to adopt critical security measures. We believe that our proposals are consistent with those recommendations. Under the proposal, regulated entities would retain the ability to determine the security measures that are reasonable and appropriate to fulfill the required standards and implementation specifications, taking into consideration the factors listed at proposed 45 CFR 164.306(b)(2). In fact, the NPRM, if adopted as proposed, would add to the rule's flexibility and scalability by adding a new factor for regulated entities to consider when determining the reasonable and appropriate security measures. [285]

Failure to adopt these basic cybersecurity requirements can have a substantial financial impact on a business. There have been many analyses regarding the cost of cybersecurity incidents and the estimates vary widely. In order to establish a defensible set of cost and loss data that is suitable for the analysis of cybersecurity incident costs in the Federal sector, the Cyber Security and Infrastructure Security Agency (CISA) Office of the Chief Economist (OCE), in the Department of Homeland Security, reviewed a broad range of cyber cost and loss studies and presented an analysis of the per-incident, aggregate, and scenario-based estimates of cyber loss. On October 26, 2020, the CISA (printed page 4282) OCE released a report with the results of their analyses and a summary of per-incident loss estimates available in the most widely cited published research, commercial datasets, and industry reports. OCE estimated the median cost of a cybersecurity incident cited in the surveyed publications ranged from \$0.5 to \$1.6 million. The maximum cost per incident cited ranged from \$11.7 million to greater than \$1 billion. The CISA OCE acknowledges in its report that the differences in the assumptions, approaches to data collection, and specific incidents included in the datasets for the above sources result in a high degree of variability among the loss estimates. [1]

3. Increased Protection of Sensitive Information Given the potential financial impacts a CUI incident may have on companies and individuals, it is imperative that Federal contractors who are entrusted with sensitive information in the performance of Government contracts adopt the basic cybersecurity hygiene requirements outlined in this rule. This increased baseline of cybersecurity hygiene across Federal contractors will reduce the number of incidents that have the potential to place sensitive information at risk and pose serious threats to individuals, Federal operations and assets, and the contractors themselves. For the remaining incidents that may occur, the requirement for contractors to report suspected or confirmed CUI incidents within 8 hours, unless a different time period is required for a specific category of CUI or a Federally-controlled facility, will allow the Federal Government to have appropriate situational awareness, quickly respond to the incident, and reduce the impact of the event.

C. Public Costs The total estimated public costs associated with this FAR rule in billions over a 10-year period are as follows: Public cost Undiscounted 2 Percent Present Value \$17.63 \$15.89 Annualized 1.76 1.77 Undiscounted public costs (in billions) by year over the 10-year period are summarized as follows: Year 1 Year 2 Year 3 Year 4 Year 5 Year 6 Year 7 Year 8 Year 9 Year 10 \$2.28 \$1.71 \$1.71 \$1.71 \$1.71 \$1.71 \$1.71 \$1.71 \$1.71 \$1.71

Subcontractors will also notify their prime contractors if they make any reports to their CSA in accordance with the provisions of paragraphs (c)(7) through (c)(10) of this section. (d) Reports of loss, compromise, or suspected compromise. The contractor will report any loss, compromise, or suspected compromise of classified information, U.S. or foreign, to the CSA in accordance with paragraph (d)(1) through (d)(3) of this section. Each CSA may provide additional guidance concerning the reporting time period. If the contractor is located on a USG facility, the contractor will submit the report to the CSA and to the head of the USG facility. (1) Preliminary inquiry. Immediately upon receipt of a security violation report involving classified information, the contractor will initiate a preliminary (printed page 83325) inquiry to ascertain all of the circumstances surrounding the presumed loss, compromise, or suspected compromise, including validation of the classification of the information. (2) Initial report. If the contractor's preliminary inquiry confirms that a loss, compromise, or suspected compromise of any classified information occurred, the contractor will promptly submit an initial report of the incident unless otherwise notified by the CSA. (3) Final report. When the investigation has been completed, the contractor will submit a final report to the CSA which, in turn, will follow CSA procedures to notify the applicable GCA. The report will include: (i) Material and relevant information that was not included in the initial report. (ii) The full name and social security number of the individual or individuals primarily responsible for the incident, including a record of prior loss, compromise,

or suspected compromise for which the individual had been determined responsible. (iii) A statement of the corrective action taken to preclude a recurrence. (iv) Disciplinary action taken against the responsible individual or individuals, if any. (v) Specific reasons for reaching the conclusion that loss, compromise, or suspected compromise occurred or did not occur. (4) Employee information in compromise cases. When requested by the CSA, the contractor will report information concerning an employee or other individual, determined to be responsible for the incident, when the information is needed by the CSA for the loss, compromise, or suspected compromise of classified information. (e) Individual culpability reports. Contractors will establish and enforce policies that provide for appropriate administrative or disciplinary actions taken against employees who violate the requirements of this rule. (1) Contractors will establish a system to manage and track information regarding employees with eligibility for access to classified information who violate the requirements of this rule in order to be able to identify patterns of negligence or carelessness, or to identify a potential insider threat.

DoD received several comments on § 117.7, to include that a facility security officer (FSO) should be a U.S. citizen with no exceptions; and the text was updated accordingly in 117.7(b). The text clarifies that the only exception for U.S. citizenship may apply to the Senior Management Official or Insider Threat Program Senior Official if the entity has a limited entity eligibility determination due to foreign ownership, control, or influence. Two commenters observed that § 117.7(h)(1)(i) did not include the frequency of security review cycles. DoD is accepting this change and has modified § 117.7(h)(1)(i) to reflect security reviews will only occur once every 12 months unless special circumstances exist, to include addressing security vulnerabilities found during a previous security review. Another commenter expressed concern the final rule allowed a CSA to conduct unannounced reviews at its discretion without any specific guidelines. Based on this comment, DoD has proposed to update § 117.7(h)(1)(ii)(A) to clarify unannounced security reviews will be conducted only if there is a possibility of the imminent loss or compromise of classified information. Eligibility Determinations DoD received several comments on eligibility determinations in § 117.10, to include a request for clarification on the system of record for personnel security clearances, clarification of requirements for current investigations, reinvestigation, and continuous evaluation requirements, definition of what is considered a break in access and break in employment, and the process for requesting and granting an extension if a temporary eligibility determination goes beyond a year. DoD is not proposing any changes based on these comments as clarification to contractors under DoD cognizance will be provided when applicable via ISLs. National Interest Determination (NID) Requirements DoD received comments on the changes to the NID requirements for a covered National Technology and Industrial Base (NTIB) entity based on section 842 of Public Law 115-232 included in § 117.11. Commenters asked for clarification on which specific entities fall under section 842 of Public Law 115-232 and recommended that NIDs be eliminated completely. The final NISPOM rule reflects language taken directly from section 842 of Public Law 115-232, which includes eliminating a NID requirement for U.S.-cleared companies owned by Australia, Canada, and the United Kingdom. DoD is not making any changes based on these comments as DoD is unable to eliminate NIDs, since the provisions for NID requirements are driven by 32 CFR part 2004, National Industrial Security Program, and not this rule. There has been no change to the NID requirements in 32 CFR part 2004 outside of section 842 Public Law 115-232. Safeguarding

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 Table 3. Effects of cyber resiliency techniques on adversarial threat events 3159 INTENDED EFFECT IMPACT ON RISK EXPECTED RESULTS Redirect (includes deter, divert, and deceive): Direct threat events away from defender-chosen resources. Reduce the likelihood of occurrence and (to a lesser extent) the likelihood of impact. · The adversary's efforts cease. · The adversary actions are mistargeted or misinformed. Deter Discourage the adversary from undertaking further activities by instilling fear (e.g., of attribution or retribution) or doubt that those activities would achieve their intended effects (e.g., that targets exist). Reduce the likelihood of occurrence

3.4.1 | Requisitos de la red para admitir una ZTA... 3.4.1 Requisitos de la red para admitir una ZTA
1. 3.4.1, todo el tráfico se inspecciona, se registra en la red y se analiza con el fin de identificar y reaccionar ante posibles ataques contra la empresa.

IA.L2-3.5.4 · REPLAY-RESISTANT AUTHENTICATION Employ replay -resistant authentication mechanisms for network access to privileged and non-privileged accounts. ASSESSMENT OBJECTIVES [NIST SP 800-171A]104 Determine if: [a] replay-resistant authentication mechanisms are implemented for network account access to privileged and non-privileged accounts. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]104 Examine [SELECT FROM: Identification and authentication policy; procedures addressing user identification and authentication; system security plan; system design documentation; system configuration settings and associated documentation; system audit logs and records; list of privileged system accounts; other relevant documents or records]. Interview [SELECT FROM: Personnel with system operations responsibilities; personnel with account management responsibilities; personnel with information security responsibilities; system or network administrators; system developers]. Test [SELECT FROM: Mechanisms supporting or implementing identification and authentication capability or replay resistant authentication mechanisms]. DISCUSSION [NIST SP 800-171 REV. 2]

The number of assessments over the phase-in period were estimated using data from the Electronic Data Access system for the contracts containing DFARS clause 252.204-7012 in fiscal years 2019, 2020, and 2021, as well as data calculated for the initial CMMC Program. This data was used in combination with an expected growth factor to estimate DoD contracts and orders in the future. Data also showed the number of awards that were made to small entities and other than small entities. The resulting estimate was phased in over 7 years to allow the ecosystem to grow and accommodate an increasing number of assessments. The assumptions and analysis of costs are provided in the regulatory impact analysis for this rule and are explained in depth. One of the assumptions is that Non-Small Entities have a team of full-time cybersecurity professionals on staff while Small Entities do not. The assumptions reflect Small Entities will likely obtain support from External Service Providers and have a staff member submit affirmations and SPRS scores for self-assessments (when applicable). DoD included an analysis of costs to meet CMMC requirements in the regulatory impact analysis for this rule. As described in the estimate included with the rule, the major cost categories for compliance with CMMC requirements are anticipated to include costs for completing a self-assessment (e.g., Level 1 or 2); costs to prepare for and undergo C3PAO assessment (Level 2); costs required to implement the Level 3 security requirements and for preparing to undergo DCMA DIBCAC assessment (Level 3). Market forces of supply and demand will determine C3PAO pricing for CMMC Level 2 certification assessments. The CMMC rule does not make any change to cost allowability as defined in the FAR 31.201-2, Determining Allowability. As addressed in the Assumptions section of the Regulatory Impact Analysis (RIA), the cost estimates for CMMC Levels 1 and 2 are based only on the assessment, certification, and affirmation activities that a defense contractor, subcontractor, or ecosystem member must take to allow DoD to verify implementation of the relevant underlying security requirements. For CMMC Level 3, cost estimates to implement applicable security requirements are included as they are a new addition to current security protection requirements. Section H costs of existing/past contracts do not apply. CCP and CCA certification costs are set by the CAICO and are market driven. The hours used in the cost estimations are based on estimates by subject matter experts. The 417.83 hours per response questioned by the commentor ties to C3PAO reporting and recordkeeping requirements for Level 2 certification assessment on small entities as identified in table 36, not Level 1 or table 39 as stated in the comment.

Compliance challenges observed through OCR's enforcement activities suggest that regulated entities would benefit from an expanded standard to provide more details on compliance expectations. Investigations of reported breaches of unsecured PHI discussed above as examples of risk analysis failures also identified a potential failure by the regulated entities to conduct appropriate information system activity review. [536] In an investigation involving a large health care provider, the ePHI of more than 12,000 patients was sold to an identity theft ring by employees who, for six months, inappropriately accessed patient account information. [537] Compliance with the requirement to implement procedures to regularly review records of activity in relevant electronic information systems, such as audit logs, access reports, and security incident tracking, could have identified and mitigated these disclosures. [538] Similarly, a business associate experienced an intrusion into its systems that it failed to notice for over 20 months. Eventually, the ePHI of more than 200,000 individuals associated with several covered entities was encrypted in a ransomware cyberattack. [539] Among other factors, OCR's investigation indicated that the business associate potentially failed to implement procedures for regularly reviewing records of activity in its relevant electronic information system, such as audit logs, access reports, and security incident tracking reports. [540] Consistent with previously issued guidance and based

on OCR's enforcement experience, the Department proposes to elevate the existing implementation specification for information system activity review to a standard and to redesignate it as proposed 45 CFR 164.308(a)(7)(i). The purpose of the proposal is to impose specific requirements on a regulated entity to review the activity occurring in its relevant electronic information systems, including the activity occurring in the components of such systems. By virtue of these proposed requirements, we would specify actions that a regulated entity is required to take to ensure that only appropriate users access ePHI and that it responds quickly to any suspicious activity in its relevant electronic information systems, including in components thereof, such as workstations that connect to or otherwise access its relevant electronic information systems. We also propose to revise the language to provide regulated entities with additional direction regarding their review of suspicious activities. The proposed standard, if adopted, would require a regulated entity to implement written policies and procedures for regularly reviewing (printed page 947) records of activity in its relevant electronic information systems. The Department proposes five implementation specifications for the proposed standard for information system activity review. The proposed implementation specification for policies and procedures at proposed 45 CFR 164.308(a)(7)(ii)(A)

Data used to estimate the numbers of illnesses, contaminating agents, and outbreak durations are taken from FDA information documenting investigations monitored by the agency from 2000-2003 (Ref. 2). The investigation information is drawn from multiple, non-standardized sources that irregularly document different aspects of investigations. The number of investigations reported in the table is not exhaustive; more investigations may be documented elsewhere. Moreover, it is possible that the information does not perfectly reflect the universe of FDA outbreak investigations because the methods for its collection and distribution are non-standardized. Nevertheless, we believe the information is sufficiently accurate, and that the list of outbreaks is sufficiently exhaustive for purposes of estimating the benefits from the recordkeeping final rule. The outbreak duration is calculated as the time between the first and last illness, and the sizes of the outbreaks are calculated as the numbers of known illnesses attributed to an outbreak. The charts that follow depict the sizes and durations of the outbreaks from 2000 to 2003 as estimated from FDA outbreak investigation data. (printed page 71617) (printed page 71618) The next diagram combines information from the two preceding diagrams and depicts the cumulative distribution by outbreak duration of the percent of all onsets of illnesses. The horizontal axis in the following diagram gives the number of days that outbreaks lasted, and the vertical axis gives the fraction of all illnesses that occurred during outbreaks of a given duration. The diagram shows that approximately 80 percent of illnesses were from outbreaks that lasted for 33 or fewer days, and 20 percent of all illnesses were from outbreaks that lasted more than 33 days. (printed page 71619) Estimates of the durations and magnitudes of outbreaks based on FDA outbreak investigation information may overestimate the true average outbreak magnitudes and durations. The outbreaks monitored by FDA may be the most difficult to investigate because they involve interstate commerce (so illnesses are geographically dispersed), and may sicken a greater number of people. Consequently, the duration and magnitudes of the outbreaks may be longer and more severe than the average duration and magnitude of all investigations, which includes investigations at the local level in addition to the national level. However, as indicated earlier, the estimates presented here are based on food safety considerations and may understate the benefits of this final rule when the possibility of bioterrorism (food security) is considered. 4. The Total Number of Illnesses

For written/paper comments submitted to the Dockets Management Staff, FDA will post your comment, as well as any attachments, except for information submitted, marked, and identified, as confidential, if submitted as detailed in Instructions. Instructions: All submissions received must include the Docket No. FDA-2023-N-3636 for FDA IT Strategy. Received comments will be placed in the docket and, except for those submitted as Confidential Submissions, publicly viewable at <https://www.regulations.gov> or at the Dockets Management Staff between 9 a.m. and 4 p.m., Monday through Friday, 240-402-7500. Confidential Submissions-To submit a comment with confidential information that you do not wish to be made publicly available, submit your comments only as a written/paper submission. You should submit two copies total. One copy will include the information you claim to be confidential with a heading or cover note that states THIS DOCUMENT CONTAINS CONFIDENTIAL INFORMATION. The Agency will review this copy, including the claimed confidential information, in its consideration of comments. The second copy, which will have the claimed confidential information redacted/blacked out, will be available for public viewing and posted on <https://www.regulations.gov>. Submit both copies to the Dockets Management Staff. If you do not

wish your name and contact information to be made publicly available, you can provide this information on the cover sheet and not in the body of your comments and you must identify this information as **confidential**. Any information marked as **confidential** will not be disclosed except in accordance with 21 CFR 10.20 and other applicable disclosure law. For more information about FDA's posting of comments to public dockets, see 80 FR 56469, September 18, 2015, or access the information at: <https://www.govinfo.gov/content/pkg/FR-2015-09-18/pdf/2015-23389.pdf>. Docket: For access to the docket to read background documents or the electronic and written/paper comments received, go to <https://www.regulations.gov> and insert the docket number, found in brackets in the heading of this document, into the **Search** box and follow the prompts and/or go to the Dockets Management Staff, 5630 Fishers Lane, Rm. 1061, Rockville, MD 20852, 240-402-7500. Submit written requests for single copies of this IT strategy to the Office of Digital Transformation, Food and Drug Administration, FDA Library, 5630 Fishers Lane, Rm. 1087, Rockville, MD 20857. Send one self-addressed adhesive label to assist that office in processing your request or include a Fax number to which the strategy may be sent. See the **SUPPLEMENTARY INFORMATION** section for information on electronic access to the draft strategy. **FOR FURTHER INFORMATION CONTACT:** Casi Alexander, Office of Digital Transformation, Food and Drug Administration, FDA Library, 5630 Fishers Lane, Rm. 1087, Rockville, MD 20857, 240-402-5171, email: Casi.Alexander@fda.hhs.gov. **SUPPLEMENTARY INFORMATION:** I. Background

SC.L2-3.13.7 · Split Tunneling CMMC Assessment Guide · Level 2 | Version 2.13 226 **FURTHER DISCUSSION** Split tunneling for a remote user utilizes two connections: accessing resources on the internal network via a VPN and simultaneously accessing an external network such as a public network or the internet. Split tunneling presents a potential opportunity where an open unencrypted connection from a public network could allow an adversary to access resources on internal network. As a mitigation strategy, the split tunneling setting should be disabled on all devices so that all traffic, including traffic for external networks or the internet, goes through the VPN. Example You are a system administrator responsible for configuring the network to prevent remote users from using split tunneling. You review the configuration of remote user laptops. You discover that remote users are able to access files, email, database and other services through the VPN connection while also being able to print and access resources on their local network. You change the configuration settings for all company computers to disable split tunneling [a]. You test a laptop that has had the new hardening procedures applied and verify that all traffic from the laptop is now routed through the VPN connection. **Potential Assessment Considerations** · Does the system prevent remote devices that have established connections (e.g., remote laptops) with the system from communicating outside that communications path with resources on uncontrolled/unauthorized networks [a]? **KEY REFERENCES** · NIST SP 800-171 Rev. 2 3.13.7

We estimate that the U.S. Government receives approximately 48 contractor incident reports each year. According to OSD subject matter experts on contractors performing private security functions, it takes approximately 30 minutes for the U.S. Government to receive, review, and analyze the information for each incident reported by a contractor. Based on our assessment, the complexity of the work is equivalent to that of a GS-11, step 5. See the rate calculation below. The estimated annual cost to the U.S. Government for receiving, reviewing, analyzing, and forwarding the information submitted by the contractor is as follows: Estimation of Federal Government Burden Hours: OMB Control Number 0704-0549 Number of responses (a) 48 Hours per response (b) .5 Estimated hours (number of responses multiplied hours per response) 24 Cost per hour (c) \$45 Annual Federal Government burden (estimated hours multiplied by cost per hour) \$1,080 The hourly rate was calculated by adding an overhead factor of 36.25 percent (taken from OMB Memo M-08-13, which provides standard cost factors for agency use) to the calendar year 2019 Office of Personnel Management rate for the Rest of the United States for a GS-11, step 5; \$33.24. Labor rate calculation: Cost per hour GS-11, step 5 as follows \$33.24 OMB burden @36.25% 12.05 Total 45.29 Total Rounded to nearest whole dollar 45.00 A. Executive Order 12866, **Regulatory Planning and Review** and Executive Order 13563, **Improving Regulation and Regulatory Review**. These Executive orders direct agencies to assess all costs, benefits, and available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). These Executive orders emphasize the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This rule has been designated a **non-significant regulatory action** under section 3(f) of Executive Order 12866. B. Congressional Review Act (5 U.S.C. 801 et seq.) Pursuant to the

Congressional Review Act, this rule has not been designated a major rule, as defined by 5 U.S.C. 804(2). C. Public Law 96-354, 'Regulatory Flexibility Act' (5 U.S.C. 601) The Under Secretary of Defense for Acquisition and Sustainment certified that this rule is not subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would not, if promulgated, have a significant economic impact on a substantial number of small entities. Therefore, the Regulatory Flexibility Act, as amended, does not require us to prepare a regulatory flexibility analysis. D. Sec. 202, Public Law 104-4 , 'Unfunded Mandates Reform Act' Section 202 of the Unfunded Mandates Reform Act of 1995 (UMRA) (2 U.S.C. 1532

AU.L2-3.3.6 · Reduction & Reporting CMMC Assessment Guide · Level 2 | Version 2.13 83
AU.L2-3.3.6 · REDUCTION & REPORTING Provide audit record reduction and report generation to support on- demand analysis and reporting. ASSESSMENT OBJECTIVES [NIST SP 800-171A]72 Determine if: [a] an audit record reduction capability that supports on-demand analysis is provided; and [b] a report generation capability that supports on-demand reporting is provided. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]72 Examine [SELECT FROM: Audit and accountability policy; procedures addressing audit record reduction and report generation; system design documentation; system security plan; system configuration settings and associated documentation; audit record reduction, review, analysis, and reporting tools; system audit logs and records; other relevant documents or records]. Interview [SELECT FROM: Personnel with audit record reduction and report generation responsibilities; personnel with information security responsibilities]. Test [SELECT FROM: Audit record reduction and report generation capability]. DISCUSSION [NIST SP 800-171 REV. 2]

(5) Based on the documentation provided, the Denial Authority will either amend the records and notify the requester and the custodian of the records of all actions taken, or deny the request. If the records are amended, those who have received the records in the past will receive notice of the amendment. (6) If the Denial Authority determines that the amendment is not warranted, he or she will provide the requester and the custodian of the records reason(s) for not amending. In addition, the Denial Authority will send the requester an explanation regarding his or her right to seek further review by the DA Privacy Act Review Board, through the Denial Authority, and the right to file a concise 'Statement of Disagreement' to append to the individual's records. (i) On receipt of a request for further review by the Privacy Act Review Board, the Denial Authority will append any additional records or background information that substantiates the refusal or renders the case complete; (ii) Within 5 working days of receipt, forward the appeal to the DA Privacy Act Review Board; and (iii) Append the servicing Judge Advocate's legal review, including a determination that the Privacy Act Review Board packet is complete. (d) DA Privacy Act Review Board. (1) The DA Privacy Act Review Board acts on behalf of the Secretary of the Army in deciding appeals of the appropriate Denial Authority's refusal to amend records. (2) The Board will process an appeal within 30 working days of its receipt. The General Counsel may authorize an additional 30 days when unusual circumstances and good cause so warrant. (3) The Board membership consists of the following principal members, comprised of three voting and two non-voting members, or their delegates. (4) Three voting members include: (i) Administrative Assistant to the Secretary of the Army (AASA) who acts as the Chairman of the Board; (printed page 46062) (ii) The Judge Advocate General; and (iii) The Chief, DA Freedom of Information and Privacy Division, U.S. Army Records Management and Declassification Agency. (5) In addition, two non-voting members include: (i) The Chief Attorney, OAASA (or designee) who serves as the legal advisor and will be present at all Board sessions to provide legal advice as required; and (ii) Recording Secretary provided by the Office of the Administrative Assistant to the Secretary of the Army. (e) DA Privacy Act Review Board meetings. (1) The meeting of the Board requires the presence of all five members or their designated representatives. Other non-voting members with subject matter expertise may participate in a meeting of the Board, at the discretion of the Chairman. (2) Majority vote of the voting members is required to make a final determination on a request before the Board.

(k) NIST SP 800-172, titled 'Enhanced Security Requirements for Protecting Controlled Unclassified Information: A Supplement to NIST Special Publication 800-171,' February 2021 (NIST SP 800-172 Feb2021), provides Federal agencies with recommended enhanced security requirements for protecting the confidentiality of CUI: (1) when the information is resident in nonfederal systems and organizations; (2) when the nonfederal organization is not collecting or maintaining information on behalf of a Federal agency or using or operating a system on behalf of an agency; and (3) where there are no specific safeguarding requirements for protecting the confidentiality of CUI prescribed by the authorizing law, regulation, or government-wide policy for the CUI category listed in the CUI

Registry. The enhanced requirements apply only to components of nonfederal systems that process, store, or transmit CUI or that provide security protection for such components when the designated CUI is associated with a critical program or high value asset. The enhanced requirements supplement the basic and derived security requirements in NIST SP 800-171 R2 and are intended for use by Federal agencies in contractual vehicles or other agreements established between those agencies and nonfederal organizations. This document is incorporated by reference as a foundational source for security requirements. (l) NIST SP 800-172A, titled "Assessing Enhanced Security (printed page 83099) Requirements for Controlled Unclassified Information," March 2022 (NIST SP 800-172A Mar2022), provides Federal agencies and nonfederal organizations with assessment procedures that can be used to carry out assessments of the requirements in NIST SP 800-172 Feb2021. The assessment procedures are flexible and can be tailored to the needs of organizations and assessors. Assessments can be conducted as (1) self-assessments; (2) independent, third-party assessments; or (3) government-sponsored assessments. The assessments can be conducted with varying degrees of rigor based on customer-defined depth and coverage attributes. The findings and evidence produced during the assessments can be used to facilitate risk-based decisions by organizations related to the CUI enhanced security requirements. This document is incorporated by reference as a foundational source for definitions and assessment. (m) ISO/IEC 17011:2017(E), titled "Conformity assessment-Requirements for accreditation bodies accrediting conformity assessment bodies," Second edition, November 2017 (ISO/IEC 17011:2017(E)), specifies requirements for the competence, consistent operation and impartiality of accreditation bodies assessing and accrediting conformity assessment bodies. This document is incorporated by reference as a source for requirements on the CMMC Ecosystem.

A DA official or employee may be found guilty of a misdemeanor and fined not more than \$5,000 for willfully-

- (i) Disclosing individually identifiable personal information to one not entitled to the information;
- (ii) Requesting or obtaining information from another's record under false pretenses;
- or (iii) Maintaining a system of records without first meeting the public notice requirements of the Act.

(b) Litigation Status Sheet. (1) When a complaint citing the Privacy Act is filed in a U.S. District Court against the Department of the Army, an Army Component, a DA Official, or any Army employee, the responsible system manager will promptly notify the Army Litigation Division, 901 North Stuart Street, Arlington, VA 22203-1837. (2) The Litigation Status Sheet at appendix E of this part provides a standard format for this notification. At a minimum, the initial notification will have items (a) through (f) provided. (3) A revised Litigation Status Sheet must be provided at each stage of the litigation. (4) When a court renders a formal opinion or judgment, copies must be provided to the Defense Privacy Office by the Army Litigation Division. (c) Administrative Remedies-Privacy Act complaints. (1) The installation level Privacy Act Officer is responsible for processing Privacy Act complaints or allegations of Privacy Act violations. Guidance should be sought from the local Staff Judge Advocate and coordination made with the system manager to assist in the resolution of Privacy Act complaints. The local Privacy Act officer is responsible for-

- (i) Reviewing allegations of Privacy Act violations and the evidence provided by the complainants;
- (ii) Making an initial assessment as to the validity of the complaint, and taking appropriate corrective action;
- (iii) Coordinating with the local Staff Judge Advocate to determine whether a more formal investigation such as a commander's inquiry or an AR 15-6 investigation is appropriate; and
- (iv) Ensuring the decision at the local level from either the Privacy Act Officer or other individual who directed a more formal investigation is provided to the complainant in writing.

(2) The decision at the local level may be appealed to the next higher command level Privacy Act Officer. (3) A legal review from the next higher command level Privacy Act Officer's servicing Staff Judge Advocate is required prior to action on the appeal. § 505.13 Computer Matching Agreement Program. (a) General provisions. (1) Pursuant to the Privacy Act and this part, DA records may be subject to computer matching, i.e., the computer comparison of automated systems of records. (2) There are two specific kinds of Matching Programs covered by the Privacy Act-

- (i) Matches using records from Federal personnel or payroll systems of records; and
- (ii) Matches involving Federal benefit programs to accomplish one or more of the following purposes-

- (A) To determine eligibility for a Federal benefit;
- (B) To comply with benefit program requirements; and

Back to Citation 650. "Considerations for Securing Electronic Media and Devices," *supra* note 631, p. 1. Back to Citation 651. *Id.* Back to Citation 652. See *id.* for a list of questions that regulated entities should consider when developing their policies and procedures regarding device and media controls. Back to Citation 653. See Richard Kissel, et al., "Guidelines for Media Sanitization," NIST Special Publication 800-88, Revision 1, National Institute of

Standards and Technology, U.S. Department of Commerce (Dec. 2014), <https://csrc.nist.gov/publications/detail/sp/800-88/rev-1/final> ; see also Proper Disposal of Electronic Devices, Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security (Feb. 1, 2021), <https://www.cisa.gov/news-events/news/proper-disposal-electronic-devices> . Back to Citation 654. See Guidelines for Media Sanitization, supra note 653; see also Proper Disposal of Electronic Devices, supra note 653. Back to Citation 655. Guidance on Disposing of Electronic Devices and Media, Office for Civil Rights, U.S. Department of Health and Human Services, p. 1 (July 2018), <https://www.hhs.gov/sites/default/files/cybersecurity-newsletter-july-2018-Disposal.pdf> . Back to Citation 656. Id. at 2. Back to Citation 657. Id. Back to Citation 658. Id. Back to Citation 659. Security Standards: Technical Safeguards, supra note 343, p. 4. Back to Citation 660. A superuser is a user that is authorized (and therefore, trusted) to perform security-relevant functions that ordinary users are not authorized to perform. NIST definition of superuser, Glossary, Computer Security Resource Center, National Institute of Standards and Technology, U.S. Department of Commerce, <https://csrc.nist.gov/glossary/term/superuser> . Back to Citation 661. See 45 CFR 164.306(d) for an explanation of required and addressable implementation specifications. Back to Citation 662. 45 CFR 164.312(a)(2)(i) . Back to Citation 663. 45 CFR 164.312(a)(2)(ii) . Back to Citation 664. 45 CFR 164.312(a)(2)(iii) . Back to Citation 665. 45 CFR 164.312(a)(2)(iv) . Back to Citation 666. 45 CFR 164.312(a)(2)(i) . Back to Citation 667. 45 CFR 164.312(a)(2)(ii) . Back to Citation 668. Security Standards: Technical Safeguards, supra note 343, p. 5. Back to Citation 669. 45 CFR 164.312(a)(2)(iii) . Back to Citation 670. Security Standards: Technical Safeguards, supra note 343, p. 6. Back to Citation 671. Id. Back to Citation 672. 45 CFR 164.312(a)(2)(iv) . Back to Citation 673. Security Standards: Technical Safeguards, supra note 343, p. 7. Back to Citation 674. Understanding the Importance of Audit Controls, Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services, p. 1 (Jan. 2017), <https://www.hhs.gov/sites/default/files/january-2017-cyber-newsletter.pdf?language=es> . Back to Citation 675. Id. Back to Citation 676. Id. at 2. Back to Citation 677. Id. Back to Citation 678. Security Standards: Technical Safeguards, supra note 343, p. 7.

Extending the compliance dates and broadening the scope of foods subject to the limited 1-year records retention period relative to the baseline are all provisions in the final rule. Cost savings from extending the compliance dates by 6 months relative to the baseline result from reductions in inventory losses and discounts in the costs realized when incurred 6 additional months into the future. These cost savings are approximately \$271 million relative to the baseline with a 7-percent discount rate, and \$163 million with a 3 percent discount rate. Adopting retention requirements based on NIST definitions based on shelf life is not assumed to increase costs, but will reduce the benefits by a negligible amount. Throughout the analysis, we have estimated costs based on the number of facilities, and assume that this number, whenever used, approximately reflects the number of persons covered by the regulation. The revised number of facilities covered by the final rule is estimated to be 707,672 (including persons who manufacture, process, pack, transport, distribute, receive, hold, or import food, and foreign based transporters that transport food in the United States). Learning costs are assumed to be incurred by all facilities and persons 2 years following enactment of this final rule and are computed by multiplying the number of facilities by the cost of learning per facility. Based on details outlined in the proposed rule, learning costs are computed using a \$25.10 wage rate and 4.5 hours spent learning for Internet users (approximately 71 percent, and 5.5 hours spent learning for non-Internet users). The total learning costs are computed to be \$85,082,000. Records redesign costs are assumed to be incurred by approximately 101,153 large and small firms 2 years following issuance of this final rule and by 222,316 very small firms after 3 years following issuance of this final rule. Persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that contacts food, and foreign based transporters that transport food in the United States are assumed not to incur records redesign costs. In this analysis, FDA assumed that all sizes of firms will bear the \$1,365 per-firm records redesign cost estimate that was used in the proposal as the most likely records redesign cost for small and very small firms. The redesign costs are \$53,508,000 after the second year and \$151,731,000 after the third year following issuance of this regulation. FDA assumes the additional records maintenance costs to be incurred by 110,081 large and small facilities 2 years following issuance of this final rule and by 379,493 facilities after 3 years and for all subsequent years following issuance of the final rule. Persons who (printed page 71642)

The Federal Cybersecurity Awareness Workforce ## The Federal Cybersecurity Awareness Workforce

Organizational cybersecurity awareness (hereafter shortened to 'security awareness') programs may experience a number of challenges, including lack of funding and staff with the appropriate knowledge and skills to manage an effective program. While prior surveys and research have examined programs in the private sector, there is little understanding of whether these findings also apply within the U.S. government. To address this gap and better understand the needs, challenges, practices, and necessary competencies of federal security awareness teams and programs, NIST conducted a research study that leveraged both qualitative and quantitative methodologies. This companion document to NISTIR 8420 'Federal Cybersecurity Awareness Programs: A Mixed Methods Research Study' reports on a subset of study results focused on identifying the current job classifications, roles, and desired knowledge and skills for security awareness professionals within the federal government. Insights gained from these results are informing guidance and other initiatives to aid federal organizations in building security awareness teams with the appropriate competencies. While focused on the U.S. government, findings may also have implications for organizational security awareness professionals in other sectors.

(iii) The CFIUS review and the DSS industrial security review for FOCI are separate processes subject to independent authorities, with different time constraints and considerations. However, CFIUS may not mitigate national security risks that are adequately addressed by other provisions of law. (iv) If the NISP process has not begun or has not been completed prior to the submission of a CFIUS notice, DSS will review, adjudicate, and mitigate FOCI on a priority basis. DSS will provide all relevant information to the OUSD(I) Security Directorate specifically, for any transaction undergoing concurrent CFIUS and DSS reviews. (A) By the 10th calendar day after the CFIUS review period begins DSS will advise the OUSD (AT&L) Manufacturing and Industrial Base Policy (MIBP) CFIUS Team electronically, with a copy to the OUSD(I) Security Directorate, of the U.S. company's FCL status (e.g., no FCL, FCL in process, TS/S/C FCL). (B) For contractors or U.S. companies in process for an FCL, DSS will provide the following input in a signed memorandum with rationale included to the Director, Security, OUSD(I) Security Directorate on or before the suspense date established by the MIBP CFIUS Team: (1) Basic identification information about the contractor, to include name, address, and commercial and government entity code. (2) FCL level. (3) Identification of current classified contracts, to include identification of GCAs and any requirement for access to proscribed information. (4) The nature and status of any discussions DSS has had with the contractor or the foreign interest regarding proposed FOCI mitigation measures. (5) Whether DSS requires additional time beyond the established MIBP CFIUS team suspense date to determine and recommend to the OUSD(I) Security Directorate whether the proposed FOCI mitigation is sufficient to address risks within the scope of DSS's FOCI authorities. (6) Identification of any known security issues (e.g., marginal or unsatisfactory security rating, unresolved counterintelligence concerns, alleged export violations). (v) If it appears that an agreement cannot be reached on material terms of a FOCI action plan, or if the U.S. company subject to the proposed transaction fails to comply with the FOCI reporting requirements of DoD 5220.22-M, DSS may recommend additional time through the OUSD(I) Security Directorate to resolve any national security issues related to FOCI mitigation. (printed page 19478)

Based on the information above, the total annual estimated cost for 28 contractors that design, develop, operate, or maintain a non-cloud FIS to comply with the requirement for a continuous monitoring strategy in year one is approximately \$408,000 (28 contractors * 160 hours * \$91.10). The cost of the continuous monitoring strategy accounts for the time needed to analyze, develop, and document a strategy or review an existing strategy and make revisions, and prepare and submit the strategy to the Government. 5. Develop and Maintain a List of Operational Technology Equipment Paragraph (k) of the new clause 52.239-YY requires all contractors that develop, implement, operate, or maintain a FIS using non-cloud computing services to develop and maintain a list of the physical location and other pertinent data on all of the operational technology (OT) equipment included within the boundary of the FIS. Contractors must provide the Government with a copy of the current and/or historical lists, upon request. All 28 contractors awarded a contract involving a non-cloud FIS will be required to develop, submit, and maintain a list of OT equipment. The Government estimates that a contractor will expend approximately 80 hours developing the list in year one, and 40 hours updating and maintaining the list each year thereafter. Using an average loaded wage rate of \$91.10 for FIS occupations, the annual estimated cost for a contractor that operates or maintains a non-cloud FIS to develop a list of OT equipment is approximately \$7,300 (80 hours * \$91.10), and approximately \$3,600 to maintain the list thereafter. It is estimated that the Government will

annually request 6 (20 percent * 28 contractors) contractors provide a copy of the OT equipment list to the Government. It is estimated that a contractor will spend one hour preparing and submitting the list to the Government. Using an average loaded wage rate of \$91.10 for FIS occupations, the total annual estimated cost for contractors to submit the OT equipment lists to the Government is approximately \$550 (6 contractors * 1 hours * \$91.10). Based on the discussion above, the total annual estimated cost for 28 contractors that develop, implement, operate, or maintain a non-cloud FIS to develop the required OT equipment list in year one is approximately \$204,000 (28 contractors * 80 hours * \$91.10), and approximately \$102,000 (28 contractors * 40 hours * \$91.10) each following year to maintain the list annually. The cost accounts for the time needed to identify the requisite equipment, gather the required data, and document or update the information. 6. Binding Operational Directives and Emergency Directives

(g) The Auditor General is authorized to act on requests for records relating to audits done by the U.S. Army Audit Agency under AR 10-2. This includes requests for related records developed by the Audit Agency. (h) The Director of the Army Staff is authorized to act on requests for all records of the Chief of Staff and its Field Operating Agencies. The Director of the Army Staff has delegated this authority to the Chief Attorney and Legal Services Directorate, U.S. Army Resources & Programs Agency (See The Judge Advocate General for the General Officer Management Office actions). The Chief Attorney and Legal Services Director, U.S. Army Resources & Programs Agency acts on requests for records of the Chief of Staff and its Field Operating Agencies (See The Judge Advocate General for the General Officer Management Office actions). (i) The Deputy Chief of Staff, G-3/5/7 is authorized to act on requests for records relating to International Affairs policy, planning, integration and assessments, strategy formulation, force development, individual and unit training policy, strategic and tactical command and control systems, nuclear and chemical matters, use of DA forces. (j) The Deputy Chief of Staff, G-8 is authorized to act on requests for records relating to programming, material integration and externally directed reviews. (k) The Deputy Chief of Staff, G-1 is authorized to act on the following records: Personnel board records, Equal Opportunity (military) and sexual harassment, health promotions, physical fitness and well-being, command and leadership policy records, HIV and suicide policy, substance abuse programs except for individual treatment records which are the responsibility of the Surgeon General, retiree benefits, services, and programs (excluding individual personnel records of retired military personnel, which are the responsibility of the U.S. Army Human Resources Command-St. Louis), DA dealings with Veterans Affairs, U.S. Soldier's and Airmen's Home; all retention, promotion, and separation records; all military education records including records related to the removal or suspension from a military school or class; Junior Reserve Officer Training Corps (JROTC) and Senior Reserve Officer Training Corps (SROTC) records; SROTC instructor records; U.S. Military Academy Cadet Records; recruiting and MOS policy issues, personnel travel and transportation entitlements, military strength and statistics, The Army Librarian, demographics, and Manprint. (l) The Deputy Chief of Staff, G-4 is authorized to act on requests for records relating to DA logistical requirements and determinations, policy concerning materiel maintenance and use, equipment standards, and logistical readiness. (m) The Chief of Engineers is authorized to act on requests for records involving civil works, military construction, engineer procurement, and ecology; and the records of the U.S. Army Engineer divisions, districts, laboratories, and field operating agencies.

- Risk Management Guidelines: Work began on SP 800-53 Revision 5, Security and Privacy Controls for Systems and Organizations, with a pre-draft call for comments, adjudication of those comments, and coordination with our JTF partners. SP 800-53 provides organizations with the security and privacy controls necessary to appropriately strengthen their systems and the environments in which those systems operate, and provides a process for selecting the appropriate controls, which contributes to systems that are resilient in the face of attacks and other threats and protect an individual's privacy. The implementation of SP 800-53, SP 800-37, Guide for Applying the Risk Management Framework to Federal Information Systems, and SP 800-137, Information Security Continuous Monitoring for Federal Information Systems and Organizations, provides organizations with near real-time information that is essential for senior leaders making ongoing risk-based decisions affecting their critical missions and business functions. - FISMA Outreach Activity to Public and Private Sector Organizations: Cybersecurity outreach briefings were conducted and support was provided to all levels of private-sector organizations and government (including federal, state and local entities) on multiple information security topics of interest. These included, for example, an effective implementation of the NIST RMF, contingency planning, interconnection security agreements, security-focused configuration management, and information security for small businesses. In addition, the

ITL FISMA Team responded to hundreds of inquiries from customers, served on cybersecurity advisory panels, and conducted outreach activities with academic institutions, providing information on NIST's security standards and guidelines, and exploring new areas of cybersecurity research and development.

3.3.5 | NULL Authentication... 3.3.5 NULL Authentication NULL authentication is a special kind of authentication.

The DoD received questions about whether CMMC requirements apply to information systems that are designated as National Security Systems, Defense Business Systems, or systems operated on the DoD's behalf. In concert with those questions, one person recommended adding NIST SP 800-53 R5 requirements to the rule for such systems. The commenter further recommended expanding applicability of the rule to include contractor-owned systems that directly affect DoD NSS. Two commenters recommend edits to clarify that CMMC requirements do not apply to NSS or to government systems operated by contractors on the DoD's behalf. One commenter asked if a Cloud Service Provider that stores CUI would have to be at Impact Level 4 in accordance with the DISA Cloud Computing Security Requirements Guide. Response: The CMMC assessment requirements apply in conjunction with FAR clause 52.204-21 and DFARS clause 252.204-7012 requirements and provide a mechanism for verifying compliance with the security requirements for safeguarding FCI or CUI (e.g., NIST SP 800-171) levied by those clauses. The CMMC Program does not alter any additional security requirements that may be applicable to contractor-owned information systems that may also meet the criteria for designation as NSS. There is no conflict between the CMMC rule and the DISA Cloud SRG, which applies to contractor information systems that are part of Information Technology (IT) services or systems operated on behalf of the Government. The CMMC rule does not apply to those systems (§.170.3(b)). The DoD declines to modify the rule because the applicability section already states this rule applies to contractor-owned information systems. b. Infrastructure Entities Comment: Many commenters had concerns about CMMC's potential impact to the energy and electric industries, internet Service Providers (ISPs) and small, disadvantaged businesses looking to contract with the DoD, especially given dependencies on appropriate marking of Controlled Unclassified Information (CUI). Another commenter referenced Executive Order 13175 , ·Consultation and Coordination with Indian Tribal Governments· and requested information on CMMC impact to and potential exemptions for Native American and small disadvantaged contractors. Another commenter stated that some small businesses may stop providing cost estimating services to Federal agencies due to ·threatened penalties· under CMMC requirements.

This option is not selected as it does not allow DoD to increase bilateral information sharing to bolster DIB cybersecurity and safeguard DoD information transiting on DIB networks. In addition, the population of defense contractors with mandatory reporting requirements would continue to exceed those eligible to participate in the DIB CS Program. Companies that submit mandatory reports but are not eligible for the DIB CS Program would continue to be excluded from receiving cyber threat information and technical assistance. Alternative #2 DoD posts generic cyber threat information and cybersecurity best practices on a publicly accessible website without directly engaging participating companies. Reason for Not Selecting Alternative #2 This alternative was not selected as companies already have access to open-source cyber threat information and best practices from multiple sources in the public sector. This alternative does not afford access by defense contractors to government-furnished cyber threat information, specifically tailored for the DIB. In addition, this alternative does not enable defense contractor interaction with DC3. Alternative #3 Revise eligibility requirements to permit all defense contractors who own or operate a covered contractor information system (approximately 80,000 defense contractors) to participate in the DIB CS Program. Using the 10% estimation used for past program participation, the program is forecasted to grow to approximately 8,000 defense contractors. Reason for Selecting Alternative #3 The revised eligibility criteria allow DoD to perform outreach to a broader DIB community. Being able to share pertinent cyber threat information with the DIB will increase both the DoD and defense contractors' knowledge of the cyber threat landscape. Giving DoD the ability to have greater visibility over issues affecting unclassified networks will allow DoD to share pertinent alerts and threat information with a larger number of DIB organizations. DoD believes that revising the eligibility criteria to apply to contractors that own or operate covered contractor information systems is an important step in managing DoD's operational risk because it will allow additional companies to begin receiving cyber (printed page 27836) threat information to inform and harden their cybersecurity posture. DIB organizations that do not meet the current eligibility requirements

to be in a DoD-sponsored cyber threat information sharing program have expressed interest in this change as noted previously by the growing percentage of ineligible applicants. Regulatory Compliance Analysis A. Executive Order 12866 , ·Regulatory Planning and Review· and Executive Order 13563 , ·Improving Regulation and Regulatory Review· Executive Order 12866

The definitions in the rule are taken directly from the statute. In the final rule, the term ·covered item· has been replaced by the term ·covered item of supply·, thereby conforming to the statute. b. Information Technology Comment: The same respondent commented that the definition of ·information technology· is defined even more expansively than in Federal Acquisition Regulation (FAR) subpart 2.1, covering information systems ranging from systems used for intelligence activities to information systems used for the ·direct fulfillment of military or intelligence missions·. Response: The definition of ·information technology· in the rule is the same as in the statute (40 U.S.C. 11101(6)). c. Supply Chain Risk Comment: One respondent requested that DoD clarify the definition of ·supply chain risk·, stating that DoD should clarify the phrase ·maliciously introduce unwanted function· to clearly explain if this is a hardware or software concern or both, and recognize that threats posed maliciously are just one class of threat. Response: The definition of ·supply chain risk· is taken directly from the statute. It addresses both hardware and software concerns and is the only class of threat to which section 806 and the rule apply. (printed page 67245) 3. Scope and Applicability a. Prescription Comment: Three respondents commented that the scope is overly broad, recommending that DoD should include the rule's provisions and clauses in NSS solicitations and contracts only. One of these respondents commented that the rule should be narrowly scoped to reflect the intent of Congress, suggesting that DoD should include the rule's provisions and clauses in solicitations and contracts for information technology NSS rather than all information technology solicitations and contract, i.e., only in ·covered procurements·. Another respondent commented that DoD should establish an independent, special review council to evaluate issues such as: (1) ·covered· systems, technologies, items, procurements, and contracts; and (2) circumstances where the clause needs to be included and where information will be withheld under DFARS 239.7305(d), thus providing an independent check to ensure that this authority is being used in a manner consistent with section 806 of the FY 2011 NDAA and the underlying policy. This respondent also suggested that successful offerors be provided information that their contracts are covered by the clause. One respondent suggested that DoD should provide offerors sufficient notice that the goods or services they offer are to be used in a covered procurement. Response: The final rule limits use of the solicitation provision and contract clause to solicitations and contracts for information technology, whether acquired as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as that term is defined at 239.7301. b. NSS Classifications Comment:

U.S. DEPARTMENT OF ENERGY RISK ASSESSMENT METHODOLOGY Volume I: DOE Risk Assessment Guideline Instructions, Resource Table, and Completed Sample Volume II: DOE Risk Assessment Worksheets

There are two types of exemptions, general and specific. The general exemption authorizes the exemption of a system of records from all but a few requirements of the Privacy Act. The specific exemption authorizes exemption of a system of records or portion thereof, from only a few specific requirements. If a new system of records originates for which an exemption is proposed, or an additional or new exemption for an existing system of records is proposed, the exemption shall be submitted with the system of records notice. No exemption of a system of records shall be considered automatic for all records in the system. The systems manager shall review each requested record and apply the exemptions only when this will serve significant and legitimate Government purposes. (b) Specific exemptions. (1) System identifier and name. RDCAA 900.1, DCAA Internal Review Case Files. (i) Exemption. Any portions of this system of records which fall under the provisions of 5 U.S.C. 552a(k)(2) and (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3), (d), (e)(1), (e)(4)(G), (H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons. (A) From subsection (c)(3) because disclosures from this system could interfere with the just, thorough and timely resolution of the complaint or inquiry, and possibly enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying or fabricating evidence or documents. (B) From subsection (d) because disclosures from this system could interfere with the just, thorough and timely resolution of the complaint or inquiry, and possibly enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying or fabricating evidence or documents. Disclosures could also subject sources and witnesses to harassment or intimidation which jeopardize the safety and well-

being of themselves and their families. (C) From subsection (e)(1) because the nature of the investigation functions creates unique problems in prescribing specific parameters in a particular case as to what information is relevant or necessary. Due to close liaison and working relationships with other Federal, state, local, foreign country law enforcement agencies, and other governmental agencies, information may be received which may relate to a case under the investigative jurisdiction of another government agency. It is necessary to maintain this information in order to provide leads for appropriate law enforcement purposes and to establish patterns of activity which may relate to the jurisdiction of other cooperating agencies. (D) From subsection (e)(4)(G) through (H) because this system of records is exempt from the access provisions of subsection (d).

These exemptions are necessary to protect the confidentiality of the records compiled for the purpose of: Enforcement of the conflict of interest statutes by the Department of Defense Standards of Conduct Counselor, General Counsel, or their designees; and determining suitability eligibility or qualifications for Federal civilian employment, military service or Federal contracts of those alleged to have violated or caused others to violate the Standards of Conduct regulations of the Department of Defense. (5) System identifier and name. DUSDP 02, Special Personnel Security Cases. (i) Exemption. All portions of this system which fall under 5 U.S.C. 552a(k)(5) are exempt from the following provisions of 5 U.S.C. 552a : (c)(3); (d). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. This system of records is exempt from subsections (c)(3) and (d) of 5 U.S.C. 552a which would require the disclosure of investigatory material compiled solely for the purpose of determining access to classified information, but only to the extent that the disclosure of such material would reveal the identity of a source who furnished information to the Government under an expressed promise that the identity of the source would be held in confidence or, prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. A determination will be made at the time of the request for a record concerning whether specific information would reveal the identity of a source. This exemption is required in order to protect the confidentiality of the sources of information compiled for the purpose of determining access to classified information. This confidentiality helps maintain the Government's continued access to information from persons who would otherwise refuse to give it. (6) System identifier and name. DODDS 02.0, Educator Application Files. (i) Exemption. All portions of this system which fall within 5 U.S.C. 552a(k)(5) may be exempt from the following provisions of 5 U.S.C. 552a : (c)(3); (d). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. It is imperative that the confidential nature of evaluation and investigatory material on teacher application files furnished the Department of Defense Dependent Schools (DoDDS) under promises of confidentiality be exempt from disclosure to the individual to insure the candid presentation of information necessary to make determinations involving applicants suitability for DoDDS teaching positions. (7) System identifier and name. DGC 20, DoD Presidential Appointee Vetting File. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. Portions of this system of records that (printed page 14805)

(iv) When a merger, sale, or acquisition involving a foreign interest and a contractor is finalized prior to having an acceptable FOCI mitigation or negation agreement in place, DSS will invalidate any existing FCL until such time as DSS determines that the contractor has submitted an acceptable FOCI action plan (see DoD 5220.22-M) and has agreed to interim measures that address FOCI concerns pending formal execution of a FOCI mitigation or negation agreement. Invalidation renders the contractor ineligible to receive new classified material or to bid on new classified contracts. If the affected GCA determines that continued access to classified material is required, DSS may continue the FCL in an invalidated status when there is no indication that classified information is at risk of compromise. If classified information remains at risk of compromise due to the FOCI, DSS will take action to impose appropriate security countermeasures or terminate the FCL, in coordination with the affected GCA. (v) Changed conditions, such as a change in ownership, indebtedness, or a foreign intelligence threat, may justify certain adjustments to the security terms under which a contractor is cleared or, alternatively, require the use of a particular FOCI mitigation or negation agreement. Depending on specific circumstances, DSS may determine that a contractor is no longer under FOCI or, conversely, that a contractor is no longer eligible for an FCL. (printed page 19473) (vi) If the contractor determined to be under FOCI does not have possession of classified material and does not have a current or pending requirement for access to

classified information, DSS will administratively terminate the FCL. (3) Assessing the Implications of FOCI.

(ii) Required to be disclosed under the Freedom of Information Act. (2) The purpose for the accounting of disclosure is to- (i) Enable an individual to ascertain those persons or agencies that have received information about them; (ii) Enable the DA to notify past recipients of subsequent amendments or Statements of Dispute concerning the record; and (iii) Provide a record of DA compliance with the Privacy Act of 1974, if necessary. (3) Since the characteristics of records maintained within DA vary widely, no uniform method for keeping the disclosure accounting is prescribed. (4) Essential elements to include in each disclosure accounting report are- (i) The name, position title, and address of the person making the disclosure; (ii) Description of the record disclosed; (iii) The date, method, and purpose of the disclosure; and (iv) The name, position title, and address of the person or agency to which the disclosure was made. (5) The record subject has the right of access to the disclosure accounting except when- (i) The disclosure was made for law enforcement purposes under 5 U.S.C. 552a(b)(7) ; or (ii) The disclosure was made from a system of records for which an exemption from 5 U.S.C. 552a(c)(3) has been claimed. (6) There are no approved filing procedures for the disclosure of accounting records; however, system managers must be able to retrieve upon request. With this said, keep disclosure accountings for 5 years after the disclosure, or for the life of the record, whichever is longer. (7) When an individual requests such an accounting, the system manager or designee will respond within 20 working days. § 505.8 Training requirements. (a) Training. (1) The Privacy Act requires all heads of Army Staff agencies, field operating agencies, direct reporting units, Major Commands, subordinate commands, and installations to establish rules of conduct for all personnel involved in the design, development, operation, and maintenance of any Privacy Act system of records and to train the appropriate personnel with respect to the privacy rules including the penalties for non-compliance (See 5 U.S.C. 552a(e)(9)). (2) To meet the training requirements, three general levels of training must be established. They are- (i) Orientation. Training that provides basic understanding of this part as it applies to the individual's job performance. This training will be provided to personnel, as appropriate, and should be a prerequisite to all other levels of training; (ii) Specialized training.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Part 252 RIN 0750-AF58 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Proposed rule with request for comments. (printed page 2646) SUMMARY: DoD is proposing to amend the Defense Federal Acquisition Regulation Supplement (DFARS) to address requirements for validation of Taxpayer Identification Numbers as part of the Central Contractor Registration process. The proposed changes are consistent with changes made to the Federal Acquisition Regulation. DATES: Comments on the proposed rule should be submitted in writing to the address shown below on or before March 23, 2007, to be considered in the formation of the final rule. ADDRESSES: You may submit comments, identified by DFARS Case 2006-D037, using any of the following methods: Federal eRulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. E-mail: dfars@osd.mil . Include DFARS Case 2006-D037 in the subject line of the message. Fax: (703) 602-0350. Mail: Defense Acquisition Regulations System, Attn: Ms. Felisha Hitt, OUSD (AT&L) DPAP (DARS), IMD 3C132, 3062 Defense Pentagon, Washington, DC 20301-3062. Hand Delivery/Courier: Defense Acquisition Regulations System, Crystal Square 4, Suite 200A, 241 18th Street, Arlington, VA 22202-3402. Comments received generally will be posted without change to <http://www.regulations.gov> , including any personal information provided. FOR FURTHER INFORMATION CONTACT: Ms. Felisha Hitt, (703) 602-0310. SUPPLEMENTARY INFORMATION: A. Background DFARS 252.204-7004 contains a substitute paragraph for use with the clause at FAR 52.204-7, Central Contractor Registration, to address DoD-unique requirements relating to contractor registration in the Central Contractor Registration (CCR) database. Item I of Federal Acquisition Circular 2005-10, published at 71 FR 36923 on June 28, 2006, amended the clause at FAR 52.204-7 to include requirements for the Government to validate a contractor's Taxpayer Identification Number (TIN), and for the contractor to consent to this validation, as part of the CCR registration process. This proposed rule amends DFARS 252.204-7004 to address TIN validation, for consistency with the changes

made to FAR 52.204-7. This rule was not subject to Office of Management and Budget review under Executive Order 12866, dated September 30, 1993. B. Regulatory Flexibility Act

A senior official from the prime contractor and any applicable subcontractor will be required to affirm continuing compliance with the specified security requirements after every assessment, including POA&M closeout, and annually thereafter. Affirmations are entered electronically in SPRS (see § 170.22 for details on Affirmation requirements, procedures, and information collection). 4. Contracts or Subcontracts With a CMMC Level 3 Certification Assessment Requirement a. Security Requirements (New) For CMMC Level 3, when CMMC becomes a final rule, contractors and applicable subcontractors will be required to implement the 24 selected security requirements from NIST SP 800-172, as detailed in table 1 to § 170.14(c)(4). CMMC Level 2 is a prerequisite for CMMC Level 3. b. Assessment Requirements (New) At Level 3, CMMC adds a requirement for contractors and applicable subcontractors to verify through DoD assessment and receive certification that all applicable CMMC Level 3 security requirements from NIST SP 800-172 have been implemented. Selected requirements are allowed to have a POA&M that must be closed out within 180 days of the assessment (see § 170.21 for details on POA&Ms). The final certification will be valid for up to three years. The DoD assessor will enter the assessment information electronically into the eMASS, that will electronically transmit the assessment results into SPRS (see § 170.18 for details on CMMC Level 3 Certification Assessment requirements and procedures, and specifically § 170.18(a)(1)(i) for information collection). c. Affirmation Requirements (New) A senior official from the prime contractor and any applicable subcontractor will be required to affirm continuing compliance with the specified security requirements after every assessment, including POA&M closeout, and annually thereafter. Affirmations are entered electronically in SPRS (see § 170.22 for details on Affirmation requirements, procedures, and information collection). Summary of Provisions Contained in This Rule Section 170.1-Purpose Section 170.1 addresses the purpose of this rule. It describes the CMMC Program and establishes policy for requiring the protection of FCI and CUI that is processed, stored, or transmitted on defense contractor and subcontractor information systems. The security standards utilized in the CMMC Program are from the FAR clause 52.204-21; NIST SP 800-171 Rev 2; and selected requirements from the NIST SP 800-172, as applicable. The purpose of the CMMC Program is for contractors (printed page 89061) and subcontractors to demonstrate that FCI and CUI being processed, stored, or transmitted is adequately safeguarded through the methodology provided in the rule. Section 170.2-Incorporation by Reference Section 170.2 addresses the standards and guidelines that are incorporated by reference. The Director of the Federal Register under 5 U.S.C. 552(a) and 1 CFR part 51

The main audiences for this publication are product security officers and security architects at IoT product manufacturers and those in their supply chain; cybersecurity test and evaluation experts; and other stakeholders in the IoT product market. This publication may also help customers or integrators of IoT products who are adopting IoT technologies in their residence or business, especially small business networks, as well as organizations concerned with conformity assessment of IoT products to published guidance. - 'Secure by Design': Uses Secure Code Storage; Secure Code Training (e.g., training starting on day one, and regularly ongoing); Secure Code Scanning (e.g., tracking vulnerabilities, hard-coded secrets, code leaks and binaries); Policy/Framework (e.g., using System Development Lifecycle (SDLC), Open Web Application Security Project(OWASP), NIST); Industry Maturity Model (using the Software Assurance Maturity Model (SAMM)); Application Lifecycle Management/Product Lifecycle Management (ALM/PLM) Integration into Development Model (using Quality Service Model Operating System (SMOS)); - 'Secure in Use': Employs mechanisms such as participating in the Bug90 program, penetration testing, and tracking metrics; and - 'Secure Thru Trust': Seeks to build connections with customers including a broad range of organizational partnerships, direct customer engagements, and the use of media to disseminate information about Zebra product security. Karin Athanas, TIC Council, pointed out that IoT product requirements will also require smart, expanded testing to ensure the outcomes can be accomplished as described. Considering the full IoT product will require wider manufacturer testing, as well as conformity certification testing, for expected and unexpected outcomes.

The panelists articulated some of the unique aspects of their HPC systems that inform their approach to security. Some of these differences included the use of dedicated login (bastion) nodes, the fact that users often do not belong to the same organization that owns or runs the HPC, the highly dynamic nature of the workloads, and the fact that users can bring and compile their own code. One panelist described how even the well-accepted practice of using multi-factor authentication is

challenging to accomplish with off-premises users who do not belong to the organization. - Multi-factor authentication - Network security monitoring - Intrusion detection - Vulnerability scanning - Log aggregation - Antivirus scanning - Endpoint detection - Hardware-based encryption OAC and the NSF have taken a holistic approach to securing science cyberinfrastructure through multiple programs that target different capabilities and challenges. For instance, the Secure and Trustworthy Computing (SaTC) program engages in fundamental cybersecurity research, while the Cybersecurity Innovation for Cyberinfrastructure (CICI) program targets applied and translational cybersecurity work for science cyberinfrastructure. CICI has three program areas: usable and collaborative security for science, reference scientific security datasets, and a transition to cyberinfrastructure resilience track. Across these areas, Dr. Beverly highlighted some particularly exciting projects, including work on improving the performance and security of data transport, analyzing and automatically patching scientific binary software, finding and fixing configuration vulnerabilities in HPC, performing encrypted search and computing on private data, and distributed credentialed access.

Executive Director, National Security Personnel System, Program Executive Office, 1401 Wilson Boulevard, Arlington, VA 22209-2325. Notification procedure: Individuals seeking to determine whether this system of records contains information about themselves should address written inquiries to the Executive Director, National Security Personnel System, Program Executive Office, 1401 Wilson Boulevard, Arlington, VA 22209-2325. Request should contain name; assigned case number; approximate case date (day, month, and year); case type; the names of the individuals and/or labor organizations filed the unfair labor practice charges; negotiability disputes; exceptions to arbitration awards; and impasses. Record access procedures: Individuals seeking access to records about themselves contained in this system of records should address written inquiries to the Executive Director, National Security Personnel System, Program Executive Office, 1401 Wilson Boulevard, Arlington, VA 22209-2325. Request should contain name; assigned case number; approximate case date (day, month, and year); case type; the names of the individuals and/or labor organizations filed the unfair labor practice charges; negotiability disputes; exceptions to arbitration awards; and impasses. Contesting record procedures: The OSD's rules for accessing records, for contesting contents and appealing initial agency determinations are published in OSD Administrative Instruction No. 81; 32 CFR part 311 ; or may be obtained from the system manager. Record source categories: Individual; other officials or employees; and departmental and other records containing information pertinent to the NSLRB action. Exemptions claimed for the system: None. (printed page 18787) Altered System of Record Notice DEPARTMENT OF DEFENSE Defense Logistics Agency Privacy Act of 1974; Systems of Records AGENCY: Defense Logistics Agency. ACTION: Notice to alter a system of records. Summary: The Defense Logistics Agency proposes to alter a system of records notice in its inventory of record systems subject to the Privacy Act of 1974 (5 U.S.C. 552a), as amended. The alteration adds two routine uses, revises the purpose category, and makes other administrative changes to the system notice. DATES: This action will be effective without further notice on (insert date thirty days after publication in the Federal Register) unless comments are received that would result in a contrary determination. ADDRESSES: Send comments to the Privacy Act Officer, Headquarters, Defense Logistics Agency, ATTN: DSS-B, 8725 John J. Kingman Road, Suite 2533, Fort Belvoir, VA 22060-6221. FOR FURTHER INFORMATION CONTACT: Ms. Mary Smith at (703) 000-0000. SUPPLEMENTARY INFORMATION: The Defense Logistics Agency notices for systems of records subject to the Privacy Act of 1974 (5 U.S.C. 552a), as amended, have been published in the Federal Register and are available from the address above. The proposed system report, as required by 5 U.S.C. 552a(r)

155 Privacy continuous monitoring means maintaining ongoing awareness of privacy risks and assessing privacy controls at a frequency sufficient to ensure compliance with applicable privacy requirements and to manage privacy risks. NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

APPENDIX F PAGE 152 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-37r2> lowest to the highest impact levels for the systems within the organization. Organizations may also consider employing the phased implementation approach by partitioning systems into subsystems or system elements and subsequently transitioning those subsystems or system elements to ongoing authorization one segment at a time until the entire system is ready for the full transition (at which time the authorizing official acknowledges that the system is now being managed by an ongoing authorization process). REAUTHORIZATION

Reauthorization actions occur at the discretion of the authorizing official in accordance with federal or organizational policy.¹⁵⁶ If a reauthorization action is required, organizations maximize the use of security and privacy risk information produced as part of the continuous monitoring processes currently in effect. Reauthorization actions, if initiated, can be either time-driven or event-driven. Time-driven reauthorizations occur when the authorization termination date is reached (if one is specified). If the system is under ongoing authorization,¹⁵⁷ a time-driven reauthorization may not be necessary. However, if the continuous monitoring program is not sufficiently comprehensive to fully support ongoing authorization, a maximum authorization period can be specified by the authorizing official. Authorization termination dates are guided and informed by federal and organizational policies and by the requirements of authorizing officials. Under ongoing authorization, a reauthorization may be necessary if an event occurs that produces risk above the acceptable organizational risk tolerance. A reauthorization may be warranted, for example, if there is a breach/incident or failure of or significant problems with the continuous monitoring program. Reauthorization actions may necessitate a review of and changes to the continuous monitoring strategy which may in turn, affect ongoing authorization. For security and privacy assessments associated with reauthorization, organizations leverage security and privacy information generated by the continuous monitoring program and fill in gaps with manual assessments. Organizations may supplement automatically-generated assessment information with manually-generated information in situations where an increased level of assurance is needed. If the security control assessments are conducted by qualified assessors with the necessary independence, use appropriate security standards and guidelines, and are based on the needs of the authorizing official, the assessment results can be applied to the reauthorization.¹⁵⁸ The senior agency official for privacy is responsible for assessing privacy controls and those assessment results can be cumulatively applied to the reauthorization. Independent assessors may assess privacy controls at the discretion of the organization. The senior agency official for privacy reviews and approves the authorization packages for information systems that process PII prior to the authorizing official making a reauthorization decision. The reauthorization action may be as simple as updating the security and privacy plans, security and privacy assessment ¹⁵⁶ Decisions to initiate a formal reauthorization include inputs from the senior agency information security officer, senior agency official for privacy, and senior accountable official for risk management/risk executive (function). ¹⁵⁷ An ongoing authorization approach requires that a continuous monitoring program is in place to monitor all implemented security controls with a frequency specified in the continuous monitoring strategy. ¹⁵⁸ [SP 800-53A] describes the specific conditions when security information can be reused to support authorization actions.

(E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. Dated: April 15, 2013. Patricia Toppings, OSD Federal Register Liaison Officer, Department of Defense. [FR Doc. 2013-09619 Filed 4-23-13; 8:45 am] BILLING CODE 5001-06-P

reporting systems in order to develop risk assessments. (c) The Contracting Officer will consider SPRS risk assessments during the evaluation of quotations or offers received in response to this solicitation as follows: (1) Item risk will be considered to determine whether the procurement represents a high performance risk to the Government. (2) Price risk will be considered in determining if a proposed price is consistent with historical prices paid for a product or a service or otherwise creates a risk to the Government. (3) Supplier risk, including but not limited to quality and delivery, will be considered to assess the risk of unsuccessful performance and supply chain risk. (d) SPRS risk assessments are generated daily. Quoters or Offerors are able to access their risk assessments by following the access instructions in the SPRS user's guide available at <https://www.sprs.csd.disa.mil/-reference.htm> . Quoters and Offerors are granted access to SPRS for their own risk assessment classifications only. SPRS reporting procedures and risk assessment methodology are detailed in the SPRS user's guide. The method to challenge a rating generated by SPRS is also provided in the user's guide. SPRS evaluation criteria are available at https://www.sprs.csd.disa.mil/-pdf/-SPRS_DataEvaluationCriteria.pdf . (e) The Contracting Officer may consider any other available and relevant information when evaluating a quotation or an offer. (End of provision) 252.213-7000 [Removed and Reserved] 13. Remove and reserve section 252.213-7000. [FR Doc. 2023-05671 Filed 3-21-23; 8:45 am] BILLING CODE 5001-06-P

[Insert name and address of entity or name and position of officer, director, partner, or similar entity official or officials] will not require, will not have, and can be effectively and formally excluded from, access to all classified information disclosed to the entity and does not occupy a position that would enable them to adversely affect the organization's policies or practices in the performance of classified contracts. (printed page 83322) Affirmation for Exclusion from Higher-level Classified Information [Insert name and address of entity or name and position of officer, director, partner, or similar entity official or officials] will not require, will not have, and can be effectively and formally excluded from access to [insert SECRET or TOP SECRET] classified information and does not occupy a position that would enable them to adversely affect the organization's policies or practices in the performance of [insert SECRET or TOP SECRET] classified contracts. (d) Insider Threat Program. Pursuant to this rule and CSA provided guidance to supplement unique CSA mission requirements, the contractor will establish and maintain an insider threat program to gather, integrate, and report relevant and available information indicative of a potential or actual insider threat, consistent with E.O. 13587 and Presidential Memorandum National Insider Threat Policy and Minimum Standards for Executive Branch Insider Threat Programs. (e) Standard practice procedures. The contractor will implement all applicable provisions of this rule at each of its cleared facility locations. The contractor will prepare written procedures when the CSA determines them to be necessary to reasonably exclude the possibility of loss or compromise of classified information, and in accordance with additional CSA-provided guidance, as applicable. (f) Cooperation with Federal agencies. Contractors will cooperate with Federal agencies and their officially credentialed USG or contractor representatives during official reviews, investigations concerning the protection of classified information, or personnel security investigations of present or former employees and others (e.g., consultants or visitors). At a minimum, cooperation includes: (1) Providing suitable arrangements within the facility for conducting private interviews with employees during normal working hours; (2) Providing, when requested, relevant employment or personnel files, security records, supervisory files, records pertinent to insider threat (e.g., security, cybersecurity, and human resources) and any other records pertaining to an individual under investigation that are, in the possession or control of the contractor or the contractor's representatives or located in the contractor's offices; (3) Providing access to employment and security records that are located at an offsite location; and (4) Rendering other necessary assistance. (g) Security training and briefings.

, the Contractor's financial statements shall be in compliance with Generally Accepted Accounting Principles in order to receive performance-based payments. (c)(1) The Contractor shall, in addition to providing the information required by FAR 52.232-32, submit information for all payment requests using the following format: (printed page 19689) (2) Incurred cost is determined by the Contractor's accounting books and records, to which the Contractor shall provide access upon request of the Contracting Officer. An acceptable accounting system in accordance with DFARS 252.242-7006 is not required for reporting of incurred costs under this clause. If the Contractor's accounting system is not capable of tracking costs on a job order basis, the Contractor shall provide a realistic approximation of the allocation of incurred costs attributable to this contract in accordance with the Contractor's accounting system. FAR 52.232-32(m) does not require certification of incurred costs. (d) Security for financing. (1) Title to the property described in paragraph (f) of the clause at FAR 52.232-32, Performance-Based Payments, is the preferred security for receipt of performance-based payments. (2)(i) If the Contractor's accounting system is not capable of identifying and tracking through the build cycle the property that is allocable and properly chargeable to this contract, the Contracting Officer may consider acceptance of one or a combination of the following alternative forms of security sufficient to constitute adequate security for the performance-based payments and so specify in the contract, consistent with FAR 32.202-4: (A) A paramount lien on assets. (B) An irrevocable letter of credit from a federally insured financial institution. (C) A bond from a surety, acceptable in accordance with FAR part 28. (D) A guarantee of repayment from a person or corporation of demonstrated liquid net worth, connected by significant ownership interest to the Contractor. (E) Title to identified Contractor assets of adequate worth.

Keywords : Cell Phone, Computer Forensics, Protocol Filter Over 2.5 billion cell phones are estimated in use in the world today and the number continues to grow. Digital evidence recovered from a cell phone can provide a wealth of information about the user, and technical advances in device capabilities generally offer opportunity for recovery of a broader range of information. Numerous forensic tools abound for automatic data recovery from cell phones. While the outlook should be positive, a number of factors have coalesced to impede progress in cell phone forensics. A

key issue is the delay between the availability of a cell phone to the public and support for the phone by a forensic tool. Forensic cell phone tools often recover data employing the same protocols used by phone managers. To avoid the problem of altering data on a phone, forensic tools restrict the protocol used to communicate with the device to only functions that are either known to be safe or involve very minor forensic issues. A potential way to gain the same advantage for phone managers is to apply a filter between the phone manager application and the device being managed that blocks harmful protocol commands from propagating. Filtering is an often used technique in computer forensics, commonly implemented in hardware or software write blockers for disk and USB device interfaces.

At the highest level of abstraction, the nation has pursued for the past several years a two-prong strategy for dealing with cybersecurity issues, namely, the continual development of cyber-protection technology and techniques, paired with the sharing of information about those capabilities, about new threats and vulnerabilities, and about data breaches (where required by law). Based on the Task Force's examination to date, these strategies will remain important. The dynamic nature of the cyber risk environment demands continuous innovation in cyber-protection capability. Ongoing improvements in education and other forms of awareness-raising are also necessary, given the fact that a significant proportion of Internet economy participants do not take adequate advantage of readily available cyber-protection tools. In response to the President's Cyberspace Policy Review, the U.S. Government is stepping up its investment in education and awareness-raising. For example, NIST has assumed overall coordination responsibility for a new National Initiative for (printed page 44220) Cybersecurity Education (NICE). [18] NICE has four tracks, each delegated to particular federal agencies. The tracks include: (1) National Cybersecurity Awareness led by the DHS; (2) K-12 and university-level Cybersecurity Education led by the Department of Education and the White House's Office of Science and Technology Policy; (3) the creation of a Federal Cybersecurity Workforce Structure led by the Office of Personnel Management; and (4) the creation of a Cybersecurity Workforce Training effort led by the DOD, DHS, and the Office of the Director of National Intelligence. The Department also recognizes that across the private sector, there are many initiatives-some nationally led, others locally led, some including public-private partnerships-aimed at improving cybersecurity awareness among businesses, consumers, and students. We seek comment on the efficacy of existing educational efforts, as well as the steps that might be taken to improve them. Are there data that demonstrate that certain educational programs qualify as best practices? What have those who are delivering cybersecurity education learned from their experiences? Which educational plans are succeeding or failing, and have providers of such educational efforts attempted to measure return-on-investment? What additional role, if any, should the government play in cybersecurity education and awareness efforts? What programs, beyond continuing education for IT professionals, workplace training for users, or curriculum development for K-12 or post-secondary institutions, should be developed? Does the private sector require government assistance in developing the kinds of materials and programs that would be useful in this area? Who should be the target audiences?

Periodic Reevaluation of the Program The Director of Operations shall reevaluate and modify the Program from time to time as deemed appropriate. The Director of Operations shall base such reevaluation and modification on the following: 1. Upon notification of a cybersecurity event, the Director of Operations must determine if the Incident Response Plan should be activated based on available information from event. 2. The Director of Operations must inform all personnel listed in Section 3.5.7 of this document when the response plan has been activated. 3. Impact to the manufacturing system must be determined by thorough investigation, and an incident type and severity level assigned. The Incident Report Template form should be used for this purpose. The severity level will be assigned by the Director of Operations in consultation with the IT Manager. 4. Approval must be received from the CEO and General Counsel if additional resources (i.e., external entities) are to be contacted to assist with incident response (e.g., forensic investigators, IT consultants, cybersecurity consultants, law enforcement, etc.). 5. The Director of Operations or IT Manager must coordinate the Incident Response Plan with stakeholders. 6. User awareness, training, and testing procedures must be reviewed after every incident and updated as necessary. 7. The General Counsel should be involved throughout the incident response due to the potential for legal action arising from the incident.

The management of configurations has traditionally been viewed as an IT management best practice. 7 Using SecCM to gain greater control over and ensure the integrity of IT resources facilitates asset

management, improves incident response, help desk, disaster recovery and problem solving, aids in software development and release management, enables greater automation of processes, and supports compliance with policies and preparation for audits. - Ability to pull information from a variety of sources (different type of components, different operating systems, different platforms, etc.); - Use of standardized specifications such as Extensible Markup Language (XML) and SCAP; - Integration with other products such as help desk, inventory management, and incident response solutions; - Vendor-provided support (patches, updated vulnerability signatures, etc.); - Compliance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidelines and link vulnerabilities to NIST [SP 800-53] controls; - Standardized reporting capability (e.g. SCAP, XML) including the ability to tailor output and drill down; and - Data consolidation into Security Information and Event Management (SIEM) tools and dashboard products. As changes are made to baseline configurations, the new baseline becomes the current version, and the previous baseline is no longer valid but is retained for historical purposes. If there are issues with a production release, retention of previous versions allows for a rollback or restoration to a previous secure and functional version of the baseline configuration. Additionally, archiving previous baseline configurations is useful for incident response and traceability support during formal audits. 23

Currently, payment instructions are being entered manually into DoD's payment systems due to a lack of clarity in the DFARS regarding payment instructions. This rule clarifies the payment instruction language in the DFARS. The clarifications in this rule will reduce data errors and inoperability problems throughout DoD's business processes created by manual entry of payment instructions in the payment systems, as well as reducing the cost of data entry. V. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. VI. Congressional Review Act As required by the Congressional Review Act (5 U.S.C. 801-808) before an interim or final rule takes effect, DoD will submit a copy of the interim or final rule with the form, Submission of Federal Rules under the Congressional Review Act, to the U.S. Senate, the U.S. House of Representatives, and the Comptroller General of the United States. A major rule under the Congressional Review Act cannot take effect until 60 days after it is published in the Federal Register. The Office of Information and Regulatory Affairs has determined that this rule is not a major rule as defined by 5 U.S.C. 804. VII. Regulatory Flexibility Act A final regulatory flexibility analysis (FRFA) has been prepared consistent with the Regulatory Flexibility Act, 5 U.S.C. 601, et seq. The FRFA is summarized as follows: (printed page 33833) The purpose of this rule is to provide clarifications on payment instructions for certain contracts based on the type of item acquired and the type of payment. DoD has found that the payment instructions often are not inserted when required and that payment instructions, if inserted, are often not appropriate for the contracts in question. An analysis of the issue showed that the appropriate accounting treatment for payments can be derived from the type of item acquired and the type of payment. In addition, the analysis highlighted the need to establish procedures for structuring progress payment requests for contracts with multiple production lots. The clarifications in this rule will promote consistency with generally accepted accounting principles and reduce data errors created by manual entry of payment instructions in the payment systems. No public comments were received in response to the initial regulatory flexibility analysis.

(C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and (k) (5) from the following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5). (iii) Reasons. To protect the identity of sources to which proper promises of confidentiality have been made during investigations. Without these promises, sources will often be unwilling to provide information essential in adjudicating access in a fair and impartial manner. (13) System identifier and name. F071 AF OSI B, Security and Related Investigative Records. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such

material would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k) (5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. To protect the identity of those who give information in confidence for personnel security and related investigations. Fear of harassment could cause sources to refuse to give this information in the frank and open way needed to pinpoint those areas in an investigation that should be expanded to resolve charges of questionable conduct. (14) System identifier and name. F031 497IG B, Special Security Case Files. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k) (5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. To protect the identity of those who give information in confidence for personnel security and related investigations. Fear of harassment could cause sources to refuse to give this information in the frank and open way needed to pinpoint those areas in an investigation that should be expanded to resolve charges of questionable conduct. (15) System identifier and name. F031 AF SP N, Special Security Files. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5)

As a result of the proposed changes in this NPRM, the enhanced security posture of regulated entities would likely reduce the number of breaches of ePHI and mitigate the effects of breaches that nonetheless occur. The Department has partially quantified these effects and presents them in a break-even analysis. The break-even analysis estimates that if the proposed changes in the NPRM reduce the number of individuals affected by breaches by 7 to 16 percent, the revised Security Rule would pay for itself. Alternatively, the same cost savings may be achieved by lowering the cost per affected individual's ePHI by 7 percent (\$35) to 16 percent (\$82), respectively. The changes to the Security Rule would likely result in important benefits and some costs that the Department is unable to fully quantify at this time. As explained further below, unquantified benefits include reductions in reputational, financial, and legal harm from breaches of individuals' ePHI, reductions in disruptions to health care delivery, increased confidence among parties to health care business transactions, and improved quality of health care. Table 2·Potential Non-Quantified Benefits

Benefits a Would benefit individuals by shielding them from unwanted disclosure of their ePHI and resulting reputational, financial, and legal harms from ePHI misuse. Would reduce reputational damage to regulated entities resulting from breaches. Would increase confidence among parties to health care business transactions that ePHI is protected to a higher degree than previously. Would reduce risk of breaches of ePHI by health plan sponsors. Would help to prevent health care cost increases to recoup financial losses from responding to breaches. Would help guard against potential data loss. Would help minimize potential disruption of service for individuals served by any of the affected entities. a Some of the items in this list represent differing perspectives on the same effect. In such cases, if more thorough quantification became feasible, we would take steps to avoid double-counting when summing the quantitative estimates. (printed page 994)

, a law that permits unsworn statements to be made under penalty of perjury as a substitute for notarization. To assist with the identification and location of requested records, when requested in the access procedures of the applicable SORN, the requester may also, at his or her option, include his or her DoD Identification Number (DoD ID Number) or Social Security Number (SSN). Providing a DoD ID Number or SSN should be appropriate for the type of record being sought. (d) When making a request for access to records as the parent or guardian for an individual who is a minor or for an individual who is determined by a court to be incompetent, the parent/guardian must establish: (1) The identity of the individual who is the subject of the record; (2) The parent/guardian's own identity; (3) That the requester is the parent or guardian of that individual, which may be proven by providing a copy of the individual's birth certificate showing parentage or a court order establishing the guardianship; and (4) That the parent or guardian is acting on behalf of the individual in making the request. (e) Members of the Military Services and married persons are not considered minors, regardless of age. (printed page 14732) §·310.4 Access exemptions. DoD may deny an individual access to certain information about the individual that resides in a DoD

Component's system of records when an exemption from the Privacy Act is claimed for the system of records and codified in the Code of Federal Regulations as described in § 310.12. When an exemption pursuant to subsection (j) or (k) of the Privacy Act exists, it will be listed in the SORN for the particular system in which the individual's information is located. Records compiled in reasonable anticipation of a civil action or proceeding may be withheld pursuant to subsection (d)(5) of the Privacy Act. § 310.5 Responses to requests for access to records. (a) Upon receipt of a request, a component will send an acknowledgment letter to the requester within 10 days (excluding Saturdays, Sundays, and legal public holidays) which shall confirm the requester's agreement to pay duplication fees, if any, and provide an assigned case file number for reference purposes. (b) In some cases, the DoD Component initially receiving the request may refer the request to another DoD Component or agency. The DoD Component that initially received the request will send the requester a notice of referral that will identify each DoD Component or agency to which the request has been referred, as well as which part of the request has been referred. (c) Access to protected health information, including medical records, is governed by the Privacy Act and DoD 6025.18-R, DoD Health Information Privacy Regulation (available at <http://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodm/602518r.pdf>).

(A) From subsection (c)(3) and (d) when access to accounting disclosures and access to or amendment of records would cause the identity of a confidential source to be revealed. Disclosure of the source's identity not only will result in the Department breaching the promise of confidentiality made to the source but it will impair the Department's future ability to compile investigatory material for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, Federal contracts, or access to classified information. Unless sources can be assured that a promise of confidentiality will be honored, they will be less likely to provide information considered essential to the Department in making the required determinations. (B) From (e)(1) because in the collection of information for investigatory purposes, it is not always possible to determine the relevance and necessity of particular information in the early stages of the investigation. In some cases, it is only after the information is evaluated in light of other information that its relevance and necessity becomes clear. Such information permits more informed decision-making by the Department when making required suitability, eligibility, and qualification determinations. (3) System identifier and name. GNSA 03, Correspondence, Cases, Complaints, Visitors, Requests. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled (printed page 14792) by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(3)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) Records maintained solely for statistical research or program evaluation purposes and which are not used to make decisions on the rights, benefits, or entitlement of an individual except for census records which may be disclosed under 13 U.S.C. 8 , may be exempt pursuant to 5 U.S.C. 552a(k)(4) . (C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (D) All portions of this system of records which fall within the scope of 5 U.S.C. 552a(k)(2) , (k)(4), and (k)(5) may be exempt from the provisions of 5 U.S.C. 552a(c)(3)

AC.L2-3.1.4 · Separation of Duties CMMC Assessment Guide · Level 2 | Version 2.13 23 FURTHER DISCUSSION No one person should be in charge of an entire critical task from beginning to end . Documenting and dividing elements of important duties and tasks between employees reduces intentional or unintentional execution of malicious activities. Example 1 You are responsible for the management of several key systems within your organization including some that process CUI . You assign the task of reviewing the system logs to two different people. This way, no one person is solely responsible for the execution of this critical security function [c]. Example 2 You are a system administrator. Human Resources notifies you of a new hire, and you create an account with general privileges, but you are not allowed to grant access to systems that contain CUI [a,b]. The program manager contacts the team in your organization that has system administration authority

over the CUI systems and informs them which CUI the new hire will need to access. Subsequently, a second system administrator grants access privileges to the new hire [c]. Potential Assessment Considerations · Does system documentation identify the system functions or processes that require separation of duties (e.g., function combinations that represent a conflict of interest or an over-allocation of security privilege for one individual) [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.1.4

CMMC addresses the Department's scaling challenges by utilizing a private-sector accreditation structure. A DoD-authorized Accreditation Body will authorize, accredit, and provide oversight of C3PAOs which in turn will conduct CMMC Level 2 Certification Assessments of actual and prospective DoD contractors and subcontractors. Defense contractors will directly contract with an authorized or accredited C3PAO to obtain a CMMC Certification Assessment. The cost of CMMC Level 2 activities is driven by multiple factors, including market forces that govern availability of C3PAOs and the size and complexity of the enterprise or enclave under assessment. The Government will perform CMMC Level 3 Certification Assessments. Government resource limitations may affect schedule availability. Reduces Duplicate or Respective Assessments of Our Industry Partners CMMC assessment results will be posted in SPRS, DoD's authoritative source for supplier and product performance information. Posting CMMC assessment results in SPRS precludes the need to validate CMMC implementation on a contract-by-contract basis. This enables DoD to identify whether the CMMC requirements have been met for relevant contractor information systems, avoids duplicative assessments, and eliminates the need for program level assessments, all of which decreases costs to both DoD and industry. CMMC 2.0-Implementation The DoD is implementing a phased implementation for CMMC 2.0 and intends to introduce CMMC requirements in solicitations over a three-year period to provide appropriate ramp-up time. This phased implementation is intended to minimize the financial impacts to defense contractors, especially small businesses, and disruption to the existing DoD supply chain. After CMMC is implemented in acquisition regulation, DoD will include CMMC self-assessment requirements in solicitations when warranted by the type of information that will be handled by the contractor of subcontractor(s). CMMC requirements for Levels 1, 2, and 3 will be included in solicitations issued after the phase-in period when warranted by any FCI and/or CUI information protection requirements for the contract effort. In the intervening period, Government Program Managers will have discretion to include CMMC requirements or exclude them and rely upon existing DFARS Clause 252.204-7012 requirements, in accordance with DoD policy. As stated in 32 CFR 170.20(a), there is qualified standards acceptance between DCMA DIBCAC High Assessment and CMMC Level 2, which will result in staggering of the dates for new CMMC Level 2 assessments. The implementation period will consist of four (4) phases as set forth in 32 CFR 170.3(e), during which time the Government will include CMMC requirements in certain solicitations and contracts. During the CMMC phase-in period, program managers and requiring activities will be required to include CMMC requirements in certain solicitations and contracts and will have discretion to include in others.

In addition to FirstNet, the Department of Commerce is home to a joint program run by NTIA and the National Institute of Standards and Technology (NIST) called the Public Safety Communications Research (PSCR) program. PSCR performs research, development, testing, and evaluation to foster nationwide public safety communications interoperability on behalf of their sponsors at the Department of Homeland Security (DHS) Office of Interoperability and Compatibility (OIC)/ Office of Emergency Communication (OEC) and FirstNet. Working with public safety organizations (e.g., APCO and the National Public Safety Telecommunications Council (NPSTC)), PSCR draws on public safety communications requirements provided by public safety practitioners to ground their efforts in the needs of the public safety community. In 2013, PSCR began cyber security research efforts related to public safety communications including public safety mobile application security. The public safety mobile application security effort focuses on improving the mobile application development process, specifically the mobile application testing tools, by understanding and collecting the security requirements relevant to the public safety community. - · Public safety related requirements - · Test protocols to characterize whether and to what extent an app meets the requirements - · Testing of apps and listing test results on a registry - · Public safety profiles

(ii) A contractor employee may be furnished a security container to temporarily store classified material at a USG agency overseas location. The decision to permit a contractor to temporarily store classified information must be approved in writing by the senior security official for the USG host organization. (iii) A contractor employee may be permitted to temporarily remove classified information from an overseas USG-controlled facility when necessary for the performance of a GCA

contract or pursuant to an approved export authorization. (A) The responsible USG security official at the facility will verify that the contractor has an export authorization or other written USG approval to have the material, verify the need for the material to be removed from the facility, and brief the employee on handling procedures. (1) In such cases, the contractor employee will sign a receipt for the classified material. (2) Arrangements will also be made with the USG custodian for the return and storage of the classified material during non-duty hours. (B) The security office at the USG facility will report violations of this policy to the applicable CSA.

(iv) A contractor employee will not store classified information at overseas divisions or subsidiaries of U.S. entities incorporated or located in a foreign country. (A) The divisions or subsidiaries may possess classified information that has been transferred to the applicable foreign government through government-to-government channels pursuant to an approved export authorization or other written USG authorization. (B) Access to this classified information at such locations by a U.S. contractor employee assigned abroad by the parent facility on a visit authorization in support of a foreign government contract or subcontract, is governed by the laws and regulations of the country in which the division or subsidiary is registered or incorporated. The division or subsidiary that has obtained the information from the foreign government will provide the access.

(v) U.S. contractor employees assigned to foreign government or foreign contractor locations under a direct commercial sales arrangement will be subject to the host-nation's industrial security policies. (3) Transmission of classified material to employees abroad. The transmission of classified material to a cleared contractor employee located outside the United States will be through USG channels. (i) If the material is to be used for other than USG purposes, an export authorization is required and a copy of the authorization, validated by the DGR, will accompany the material. The material will be addressed to a U.S. military organization or other USG organization (e.g., an embassy). (ii) USG organization abroad will be responsible for custody and control of the material. (4) Security briefings.

wledge base; - Provision of outreach for small- and mediumsized businesses (SMBs), including guidance provided by the Applied Cybersecurity Division (ACD) in NIST Interagency Report (NISTIR) 7621 Rev. 1, Small Business Information Security: The Fundamentals ; - Coordinating with critical infrastructure owners and operators, regulators, and other industry organizations through a variety of meetings and industry events to ensure the understanding and use of the Framework; - Analyzing various industry work products (such as mapping documents) for Framework correctness; - Consulting with state and local governments, and the governments of other nations regarding their alignment with both the principles and the cybersecurity outcomes of

Workshop participants agreed that more education can help consumers understand why updates/patches are important to maintaining the cybersecurity of a device, and the relationship among security, safety, and privacy. Consumers value privacy; however, workshop respondents agreed that they lack awareness around how their privacy is impacted when an IoT device is deployed in their homes. Moreover, workshop participants agreed that consumers can better understand the issues around privacy and how it affects them more than they can cybersecurity. Jean Camp said, 'Consumers are willing to pay more for security/privacy, but they need information about security/privacy to make informed decisions.' Consumers are also more concerned with infringements on their privacy, but do not feel empowered or know what actions to take to protect themselves. Julie Haney put it simply: 'People don't trust manufacturers to respect their privacy.' All combined, these factors give consumers a sense of discomfort around home IoT devices. Takeaway 7: Consumer education about home IoT cybersecurity should be an ongoing, shared responsibility among stakeholders.

The SDNS architecture, and its associated specifications, were developed as a cooperative project between government and industry. The project was sponsored by the National Security Agency, and supported by the National Institute of Standards and Technology (formerly the National Bureau of Standards) and the Defense Communications Agency. Twelve leading U.S. companies in computers and telecommunications made significant contributions of their technical talents and development resources. The combined efforts of these organizations produced the basis for improved security technology, interoperable security standards, and costeffective security for computers and telecommunications. | ISO 8473 | 01 March 1986 Final Text of DIS 8473, Protocol for Providing the Connectionless-mode Network Service | |-----|-----

-----|
| ISO 8348 | 15 July 1987 Final Text of DIS 8348: Information processing systems - Data communications - Network service definition | | ISO 7498 | 15 Oct. 1987 Information Processing

Systems - Open Systems Interconnection - Basic Reference Model || ISO 7498/2 | March 1987
Information Processing Systems - Open Systems Interconnection - Security Architecture || ISO 8348/DAD 1 | Information Processing Systems - Data 07 Aug. 1985 Communications - Network Service Definition - Addendum 1 || ISO 8348/DAD2 | Information Processing Systems - Data 29 Feb.

Commenters suggested several actions the Department could take to mitigate capacity-related risks, including: extending the phase-in of Level 2 certification requirements; prioritizing companies for Level 2 phase-in; allowing C3PAOs to issue interim or conditional certifications when unable to timely complete contractor assessments; and waiving requirements for OSCs that are in the assessment process but not yet certified. Some asked that DoD forecast the volume and timing of Level 3 certification requirements and clearly communicate those assessment requirements with contractors. Another requested forecasts of both Level 2 and Level 3 assessment capacity against various demand scenarios for each certification level. Several commenters suggested that CMMC assessment requirements for External Service Providers (ESPs) will also impede CMMC implementation, as ESPs (1) must be CMMC certified before an OSC can include them in their CMMC certification assessment scope and (2) will be competing with DIB companies for scarce C3PAO assessors. Commenters suggested ways to reduce burden on ESPs, which included: allowing use of non-compliant ESPs until Phase 3 and prioritizing certification assessments for ESPs ahead of other assessments. Several commenters expressed concern about CCA and CCP roles, based on perceived scarcity of candidates in the job market compared with demand for similar services. Concerns included the potential for CCA and CCP burnout from overwork, dissatisfaction with repetitive assessments tasks, limited career path in the roles, and the complexity of operating within the CMMC ecosystem. One commenter compared CCA and CCP roles with those of Certified Public Accountants and Certified Information System Auditors, who have access to more varied opportunities and industries. Response: DoD received numerous comments about the use of ESPs which do not process, store, or transmit CUI. In response, the DoD revised the rule to reduce the assessment burden for ESPs. ESP assessment, certification, and authorization requirements in 32 CFR 170.19(c)(2) and (d)(2) have been updated. ESPs that are not CSPs and do NOT process, store, or transmit CUI, do not require CMMC assessment or certification. Services provided by an ESP are in the OSA's assessment scope. The phased implementation plan described in § 170.3(e) is intended to address ramp-up issues, provide time to train the necessary number of assessors, and allow companies time to understand and implement CMMC requirements. The DoD has updated the rule to add an additional six months to the Phase 1 timeline. Phase 2 will start one calendar year after the start of Phase 1. It is beyond the scope of this rule for DoD to determine the order in which organizations are assessed.

3.3.2 | Implementation Considerations... 3.3.2. 3.3.2, and recommendations regarding cryptographic module validation are described in Section 3.

. Compensating controls are implemented in the place of MFA to protect ePHI. [786] The Department does not propose to require that compensating controls be technical controls. Rather, a regulated entity should consider the nature of the exception, operating environment, and other appropriate circumstances to determine what controls are reasonable and appropriate and implement compensating controls effective for those circumstances. For example, if a software program does not support MFA, deploying a firewall or increasing the sensitivity of an existing firewall protecting that software may in some circumstances constitute a reasonable and appropriate compensating control. [787] In some instances, physical safeguards may serve as reasonable and appropriate compensating controls. For example, limiting access to certain components of a relevant electronic information system to workforce members who meet certain requirements may be a reasonable and appropriate compensating control under some circumstances. In most cases, it would be reasonable and appropriate for a regulated entity to implement multiple compensating controls to ensure that the affected electronic information system is secured. The Department proposes at proposed 45 CFR 164.312(f)(2)(iv)(B) (1) that, to comply with an exception at paragraph (f)(2)(iii)(A) or (B) or (f)(2)(iii)(C)(1) or (2), the regulated entity would be required to secure the relevant electronic information system with reasonable and appropriate compensating controls that have been reviewed, approved, and signed by the regulated entity's Security Official. Because exceptions are a departure from the designed Security Rule framework, the Department intends to ensure appropriate review by the Security Official of controls selected by the regulated entity to compensate for the absence of MFA. Merely because a regulated entity's Security Official has reviewed, approved, and signed off on compensating controls does not mean that those controls are effective. The regulated entity would also be required to give due consideration to the circumstances surrounding the

exception and implement compensating controls effective for those specific circumstances. With respect to the exception at proposed 45 CFR 164.312(f)(2)(iii)(C) (3), the Department proposes at proposed 45 CFR 164.312(f)(2)(iv)(B) (2

(Response) FDA agrees with these comments in part. In this final rule, FDA is requiring that records be made available as soon as possible, but not more than 24 hours from the time of receipt of an official request. FDA does not agree with the comments' suggestion that more time be made available if a request for records is made outside of the working week. FDA notes that it would only access the records if FDA has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals. Under these circumstances, it is critical for FDA to move as quickly as possible to trace backwards to identify the source of any such adulteration and trace forward from that source to remove all similarly adulterated food from commerce to protect the public health. FDA notes that although the rule sets an outer limit of 24 hours to provide records, it requires that records be provided as soon as possible. (Comment 144) Several comments urge FDA to reconsider its proposed definition of work hours (8 a.m. to 6 p.m.). The comments state that in most ports of entry, the hours of operation of the trade community are established to mirror the hours of the commercial operations of CBP. If FDA requests records outside of those hours of operation, FDA could encounter difficulty in contacting the appropriate parties from whom to request records. Comments suggest that FDA use the phrase during times in which a firm is operating or during a firm's normal business hours. (Response) FDA is no longer defining work hours, and has modified its proposed records availability requirement to as soon as possible, not to exceed 24 hours from the time of receipt of the official request. (Comment 145) Some comments state that the agency has not considered difficulties of compliance in the real world where there are different time zones within the United States and foreign countries. According to these comments, mandating an unattainable compliance time may cause great confusion globally and may actually impede the information gathering process. Comments urge FDA to allow for records to be provided to FDA within a timeframe not to exceed 24 hours or other timeframe appropriate to the scope of records being sought. Others suggest 24 hours for domestic and 36 hours for foreign facilities. (Response) FDA agrees in part with these comments. FDA has deleted the 4-hour and 8-hour requirements. The final rule requires all records to be made available as soon as possible, not to exceed 24 hours from the time of receipt of the official request. With respect to the comments suggestion that foreign facilities be given 36 hours, FDA notes that foreign persons (except for foreign persons who transport food in the United States) are not subject to these final recordkeeping regulations.

From the NIST SP 800-172 Rev 3 Final Public Draft: Appendix B provides definitions for the terminology used in SP 800-172r1. The definitions are consistent with the definitions contained in the National Information Assurance Glossary [16] unless otherwise noted. advanced persistent threat An adversary that possesses sophisticated levels of expertise and significant resources which allow it to create opportunities to achieve its objectives by using multiple attack vectors, including cyber, physical, and deception. These objectives typically include establishing and extending footholds within the IT infrastructure of the targeted organizations for purposes of exfiltrating information; undermining or impeding critical aspects of a mission, program, or organization; or positioning itself to carry out these objectives in the future.

implementation. DCMA DIBCAC will score the OSC using the scoring methodology provided in § 170.24. All objectives must be met in order for a security requirement to be considered fully implemented; in some cases, if not all objectives are met, some security requirements may be placed on a POA&M as defined in § 170.21. If the minimum score has been achieved and some security requirements are in a POA&M, the OSC has a Conditional Certification Assessment; if the minimum score has been achieved and no security requirements are in a POA&M, the OSC has a Final Certification Assessment. For Conditional Certification Assessments, a POA&M close-out must be conducted within 180 days as described in § 170.21(b). After both Conditional Certification Assessment and Final Certification Assessment, DCMA DIBCAC will input the OSC's results into the CMMC instantiation of eMASS as described in § 170.18(a)(1)(i). After both Conditional Certification Assessment and Final Certification Assessment, the OSC must submit an affirmation as described in § 170.22. In order to be eligible for a contract with a CMMC Level 3 Certification Assessment requirement, the OSC must have a CMMC Level 3 Conditional Certification Assessment or CMMC Level 3 Final Certification Assessment and have submitted an affirmation. The CMMC Level 3 Certification Assessment must be completed tri-annually and the affirmation must be completed annually. Section 170.19-CMMC Scoping

Section 170.19 addresses the requirements for the scoping of each CMMC Level assessment. Scoping determines which assets are included in a given assessment and the degree to which each is assessed. The CMMC Assessment Scope is specified prior to any CMMC assessment, based on the CMMC Level being assessed. The Level 2 CMMC Assessment Scope may also be affected by any intent to achieve a CMMC Level 3 Certification Assessment, as detailed in § 170.19(e). Scoping for CMMC Level 1, as detailed in § 170.19(b), consists of all assets that process, store, or transmit FCI. These assets are fully assessed against the applicable CMMC security requirements identified in § 170.14(c)(2) and following the procedures in § 170.15(c). All other assets are out of scope and are not considered in the assessment.

GIDEP alerts are only used if they are Government-generated (Agency Action Notice) with a Commercial and Government Entity (CAGE) code reported explicitly for Suspected Counterfeit or Failure Experience. SPRS does not search GIDEP narratives or text. It only searches for data indicating that the item has been identified as suspected counterfeit or has been determined to be a material failure. Comment: One respondent commented that Mechanization of Contract Administration Services (MOCAS) is not specifically intended to measure on-time delivery performance and will require substantial investment by industry and DoD buying commands to maintain its accuracy and reliability. Response: SPRS only uses MOCAS records that provide a specific contractor's Commercial and Government Entity (CAGE) code, product service code (PSC), and a required delivery date on a contract line item that can be matched to an actual delivery date. This constrained usage mitigates the concerns the respondent identified. Comment: One respondent commented that the SPRS system itself may not be able to handle the (printed page 17337) administrative and logistical challenges that will arise under its expanded use. Response: DoD does not expect any issues with increased user traffic as a result of this rule. SPRS has recently experienced a rapid increase in user activity without any system impacts. Publication of this rule will not adversely impact operation of the system or the program office. C. Other Changes The following are amplifying changes to the rule that are not based on public comments, but were made to add clarity: The term 'overall risk assessments' at DFARS 204.7602 and 204.7603 was changed to 'risk assessments' throughout the final rule to use language consistent with the SPRS website. Some instances of the terms 'evaluated' and 'evaluation' were replaced with the term 'considered' and 'shall consider' to clarify that risk assessments are not a mandatory, stand-alone, evaluation factor for source selections and that the contracting officer shall 'consider' the risk assessments, if available, as part of broader evaluation factors during evaluation of quotations or offers and when determining contractor responsibility. DFARS 204.7603, Procedures, was updated to clarify the scope of SPRS risk assessments required to be considered when procuring supplies and services and the scope of SPRS risk assessments required to be considered when procuring an end product (see FAR 2.101) identified by an available material identifier (see Procedures, Guidance, and Information (PGI) 204.7603). The contracting officer shall consider price risk and supplier risk, if available, as part of the award decision. For the procurement of an end product identified by an available material identifier, the contracting officer shall also consider item risk. DFARS 204.7603, Procedures, was updated to clarify that contracting officers shall use their discretion in considering the information available in SPRS.

(ii) When placing an order with a schedule contractor for an end product identified by a material identifier that is available as described at PGI 204.7603, and item risk was not previously considered during award of the schedule contract, the contracting officer shall also consider SPRS assessments of item risk in the award decision. (iii) Use the provision at 252.204-7024, Notice on the Use of the Supplier Performance Risk System, as prescribed in 204.7604 to the extent permitted by the Federal Supply Schedule. PART 209-CONTRACTOR QUALIFICATIONS 4. Amend section 209.105-1 by revising paragraph (2) to read as follows: 209.105-1 Obtaining information. * * * * * (2) A satisfactory performance record is a factor in determining contractor responsibility (see FAR 9.104-1(c)). (i) One source of information relating to contractor performance is the Contractor Performance Assessment Reporting System (CPARS), available at <https://www.cpars.gov/>. (ii) Information relating to contract terminations for cause and for default is also available through the Federal Awardee Performance and Integrity Information System (FAPIIS) module of CPARS, available at <https://sam.gov> (see FAR subpart 42.15). This termination information is just one consideration in determining contractor responsibility. (iii) Contracting officers shall consider the supplier risk assessment available in the Supplier Performance Risk System at <https://piee.eb.mil/> when determining responsibility. See 204.7603(c). PART 212-ACQUISITION OF COMMERCIAL PRODUCTS AND COMMERCIAL SERVICES 5. Amend section 212.203 by adding paragraph (3) to read as follows: 212.203

Procedures for solicitation, evaluation, and award. * * * * * (3) See 204.7603 for procedures on the required use of Supplier Performance Risk System risk assessments as part of the award decision. 6. Amend section 212.301 by: a. Adding paragraph (f)(ii)(O); b. Removing paragraph (f)(v); and c. Redesignating paragraphs (f)(vi) through (xx) as paragraphs (f)(v) through (xix). The addition reads as follows: 212.301 Solicitation provisions and contract clauses for the acquisition of commercial products and commercial services. * * * * * (f) * * * (ii) * * * (O) Use the provision at 252.204-7024, Notice on the Use of the Supplier Performance Risk System, as prescribed in 204.7604. * * * * * PART 213-SIMPLIFIED ACQUISITION PROCEDURES 7. Revise section 213.106-2 to read as follows: 213.106-2 Evaluation of quotations or offers. (b)(i) See 204.7603 for procedures on the requirement for contracting officers to consider Supplier Performance Risk System risk assessments as a basis of award. 8. Revise section 213.106-2-70 to read as follows: 213.106-2-70 Solicitation provision. Use the provision at 252.204-7024, Notice on the Use of the Supplier Performance Risk System, as prescribed in 204.7604. PART 215-CONTRACTING BY NEGOTIATION 9. Amend section 215.304 by adding paragraph (c)(viii) to read as follows: 215.304 Evaluation factors and significant subfactors. (c) * * *

It also aligns with the Department's enhanced CPG for Centralized Incident Planning and Preparedness by requiring a regulated entity to maintain, revise, and test security incident response plans. [603] Additionally, the Department proposes to redesignate the implementation specification for response and reporting at 45 CFR 164.308(a)(6)(ii) as 45 CFR 164.308(a)(12)(ii)(B) and to rename it ·Response·. We also propose to modify the existing implementation specification by separating it into two paragraphs: one at paragraph (a)(12)(ii)(B)(1) for identifying and responding to suspected or known security incidents, and the other at paragraph (a)(12)(ii)(B)(2) for mitigating, to the extent practicable, the harmful effects of suspected or known security incidents. The Department also proposes to add three additional paragraphs to this implementation specification. Proposed 45 CFR 164.308(a)(12)(ii)(B) (3) would require a regulated entity to identify and remediate, to the extent practicable, the root cause(s) of suspected or known security incidents, while proposed 45 CFR 164.308(a)(12)(ii)(B) (4) would require the regulated entity to eradicate the security incidents that are suspected or known to the regulated entity. We would expect eradication to include the removal of malicious software, inappropriate materials, and any other components of the incident from the regulated entity's relevant electronic information systems. [604] Finally, proposed 45 CFR 164.308(a)(12)(ii)(B) (5) would require a regulated entity to develop and maintain documentation of investigations, analyses, mitigation, and remediation for security incidents that are suspected or known. For example, verbal reports of a suspected or known security incident would be required to be documented in writing. Under proposed 45 CFR 164.316(b)(1) , if finalized, a regulated entity would be required to maintain such documentation for six years from the date of its creation or the date when it last was in effect, whichever is later. These proposals are consistent with existing guidance described above and with other proposals or existing regulatory standards to secure health information. [605] o. Section 164.308(a)(13)(i)·Standard: Contingency Plan The purpose of any contingency plan is to allow an organization to return to its daily operations as quickly as possible after an unforeseen event. [606]

CUI (Controlled Unclassified Information) and FCI (Federal Contract Information) are distinct categories with different protection requirements: **FCI** (Federal Contract Information): - Information not intended for public release, provided by or generated for the Government under a contract - Requires CMMC Level 1 (15 basic safeguarding requirements from FAR 52.204-21) - Lower protection threshold - Does NOT include information provided to the public or simple transactional information **CUI** (Controlled Unclassified Information): - Information requiring safeguarding or dissemination controls per law, regulation, or Government-wide policy - Requires CMMC Level 2 (110 NIST SP 800-171 requirements) or Level 3 (NIST SP 800-172 enhanced) - Higher protection threshold - Includes 125 categories across 20 groupings (ISOO CUI Registry) Key distinction: All CUI is also FCI, but not all FCI is CUI. The type of information determines the CMMC level required. Contracts specify which type of information the contractor will handle.

IA.L2-3.5.1 · Identification [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13 113 identification may be defined by type, by device, or by a combination of type/device. NIST SP 800-63-3 provides guidance on digital identities. FURTHER DISCUSSION Make sure to assign individual, unique identifiers (e.g., user names) to all users and processes that access company systems . Authorized devices also should have unique identifiers. Unique identifiers can be as

simple as a short set of alphanumeric characters (e.g., SW001 could refer to a network switch, SW002 could refer to a different network switch). This requirement, IA.L2-3.5.1, provides a vetted and trusted identity that supports the access control mechanism required by AC.L2-3.1.1. Example You want to make sure that all employees working on a project can access important information about it. Because this is work for the DoD and may contain CUI, you also need to prevent employees who are not working on that project from being able to access the information. You assign each employee is assigned a unique user ID, which they use to log into the system [a]. Potential Assessment Considerations · Are unique identifiers issued to individual users (e.g., usernames) [a]? · Are the processes and service accounts that an authorized user initiates identified (e.g., scripts, automatic updates, configuration updates, vulnerability scans) [b]? · Are unique device identifiers used for devices that access the system identified [c]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.5.1 · FAR Clause 52.204-21 b.1.v

(A) Compliance with the approved security arrangement, standard rules, and applicable laws and regulations. (B) Problems regarding the practical application or utility of the security arrangement. (C) Security controls, practices, or procedures and whether they warrant adjustment. (ii) Annual Certification. For contractors operating under a VTA, PA, SSA, or SCA, DSS will obtain from the Chair of the GSC an implementation and compliance report one year from the effective date of the agreement and annually thereafter. DSS will review the annual report; address, resolve, or refer issues identified in the report; document the results of this review and any follow-up actions; and keep a copy of the report and documentation of related DSS actions on file for 15 years. The GSC's annual report must include: (A) A detailed description stating how the contractor is carrying out its obligations under the agreement. (B) Changes to security procedures, implemented or proposed, and the reasons for those changes. (C) A detailed description of any acts of noncompliance with FOCI provisions and a discussion of steps taken to prevent such acts from recurring. (D) Any changes or impending changes of senior management officials or key board members, including the reasons for the change. (E) Any changes or impending changes in the organizational structure or ownership, including any acquisitions, mergers, or divestitures. (F) Any other issues that could have a bearing on the effectiveness of the applicable agreement. (11) Foreign Government Ownership or Control. (i) In accordance with 10 U.S.C. 2536, the DoD cannot award contracts involving access to proscribed information to a company effectively owned or controlled by a foreign government unless a waiver has been issued by the Secretary of Defense or designee. (ii) A waiver is not required if the company is cleared under a PA or VTA because both agreements effectively negate foreign government control. (iii) DSS will, after consultation with the GCA, determine if a waiver is needed in accordance with subpart 209.104-1 of the Defense Federal Acquisition Regulation Supplement ·Responsible Prospective Contractors, General Standards· (available at http://www.acq.osd.mil/dpap/dars/dfars/pdf/r20090115/209_1.pdf). The GCA will request the waiver from the USD(I) and provide supporting information, to include a copy of the proposed NID. (iv) Upon receipt of an approved waiver, the GCA will forward the waiver and the NID to DSS. (v) If the USD(I) does not grant the waiver, the company may propose to DSS an appropriate PA or VTA. Otherwise, the company is not eligible for access to proscribed information. (12) Changed Conditions. (i) DSS will require contractors to submit timely reports of changes to FOCI by DSS-designated means in accordance with DoD 5220.22-M.

- c. Providing documentation with details describing external authentication IoT platforms, and associated authentication methods, that can be used with the IoT device. 2. Establish communications that provide details about the security capabilities of the IoT device software components. Information that may be necessary to provide describing the technical security capabilities include details and actions such as: - a. Providing details about how the security capabilities of the IoT device software components meet regulatory and other legal and policy requirements. 8 3. Establish communications for the IoT device customers with details for the security capabilities of the hardware components. Information that may be necessary to provide describing the security capabilities of hardware components include details and actions such as: - a. Providing the IoT device customers with details about the security capabilities of the IoT device hardware components. 4. Establish communications providing IoT device management details that can be incorporated within the IoT device customer's system development life cycle. Information that may be necessary to provide about IoT device security management include details and actions such as: - a. Providing the details necessary for customers to 1) manage the IoT device within their system using their organizationally-defined system development life cycle's associated information security considerations, 2) assign individuals with IoT device information security roles and

responsibilities, and 3) integrate the IoT device within the organizational information security risk management process. - b. Providing communications and the detailed instructions for implementing a hierarchy of privilege levels to use with the IoT device and/or necessary associated information systems. - c.

defense-in-depth Information security strategy integrating people, technology, and operations capabilities to establish variable barriers across multiple layers and missions of the organization. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 d discussion 2895

Accordingly, we do not believe that the proposed rule would pose unique implementation challenges that would justify an extended compliance period (i.e., a period longer than the standard 180 days provided in 45 CFR 160.105). Further, the Department believes that adherence to the standard compliance period is necessary to timely address the circumstances described in this NPRM. Thus, the Department proposes to apply the standard compliance date of 180 days after the effective date of a final rule. [26] To help reduce administrative burdens on regulated entities, the Department proposes to add a provision at 45 CFR 164.318 affording regulated entities a transition period (beyond the 180-day compliance period) to modify business associate contracts (herein referred to as business associate agreements) or other written arrangements [27] that would qualify for the longer transition period, as discussed further below. The Department seeks comment on the proposed compliance period and transition period.

C. Table of Abbreviations/Commonly Used Acronyms in This Document

As used in this preamble, the following terms and abbreviations have the meanings noted below.

Term	Meaning
AI	Artificial Intelligence.
ANSI	American National Standards Institute.
AR	Augmented Reality.
ARRA	American Recovery and Reinvestment Act of 2009.
ASTP/ONC	Assistant Secretary for Technology Policy and Office of the National Coordinator for Health Information Technology.
CISA	Cybersecurity & Infrastructure Security Agency.
CMS	Centers for Medicare & Medicaid Services.
CPG	Cybersecurity Performance Goal.
Department of HHS	Department of Health and Human Services.
EHR	Electronic Health Record.
E.O.	Executive Order.
ePHI	Electronic Protected Health Information.
FDA	Food & Drug Administration.
FISMA	Federal Information Security Modernization Act.
FTC	Federal Trade Commission.
Health IT	Health Information Technology.
(printed page 902)	
HIPAA	Health Insurance Portability and Accountability Act of 1996.
HITECH Act	Health Information Technology for Economic and Clinical Health Act of 2009.
ICR	Information Collection Request.
IIHI	Individually Identifiable Health Information.
IT	Information Technology.
MFA	Multi-factor Authentication.
NAICS	North American Industry Classification System.
NCVHS	National Committee on Vital and Health Statistics.
NIST	National Institute of Standards and Technology.
NPRM	Notice of Proposed Rulemaking.
OCR	Office for Civil Rights.
OMB	Office of Management and Budget.
ONC	Office of the National Coordinator for Health Information Technology.
PHI	Protected Health Information.
PRA	Paperwork Reduction Act of 1995.
PSAO	Pharmacy Services Administration Organizations.
RFA	Regulatory Flexibility Act.
RIA	Regulatory Impact Analysis.
SBA	Small Business Administration.
SRMA	Sector Risk Management Agency.
SSA	Social Security Act of 1935.
UMRA	Unfunded Mandates Reform Act of 1995.
VR	Virtual Reality.
II.	Statutory Authority and Regulatory History
A.	Statutory Authority and History
1.	Health Insurance Portability and Accountability Act of 1996 (HIPAA)

CMMC Level 1 security requirements. The security requirements in CMMC Level 1 are those set forth in 48 CFR 52.204-21(b)(1)(i) through (xv) . (3) CMMC Level 2 security requirements. The security requirements in CMMC Level 2 are identical to the requirements in NIST SP 800-171 R2. (4) CMMC Level 3 security requirements. The security requirements in CMMC Level 3 are selected from NIST SP 800-172 Feb2021, and where applicable, Organization-Defined Parameters (ODPs) are assigned. Table 1 to this paragraph identifies the selected requirements and applicable ODPs that represent the CMMC Level 3 security requirements. ODPs for the NIST SP 800-172 Feb2021 requirements are italicized, where applicable: Table 1 to § 170.14(c) (4) Security requirement No.* CMMC Level 3 security requirements (selected NIST SP 800-172 Feb2021 security requirement with DoD ODPs italicized) (i) AC.L3-3.1.2e Restrict access to systems and system components to only those information resources that are owned, provisioned, or issued by the organization. (ii) AC.L3-3.1.3e Employ secure information transfer solutions to control information flows between security domains on connected systems. (iii) AT.L3-3.2.1e Provide awareness training upon initial hire, following a significant cyber event, and at least annually , focused on recognizing and responding to threats from social engineering, advanced persistent threat actors, breaches, and suspicious behaviors; update the training at least annually or when there are significant changes to the

threat. (iv) AT.L3-3.2.2e Include practical exercises in awareness training for all users, tailored by roles, to include general users, users with specialized roles, and privileged users, that are aligned with current threat scenarios and provide feedback to individuals involved in the training and their supervisors. (v) CM.L3-3.4.1e Establish and maintain an authoritative source and repository to provide a trusted source and accountability for approved and implemented system components. (vi) CM.L3-3.4.2e Employ automated mechanisms to detect misconfigured or unauthorized system components; after detection, remove the components or place the components in a quarantine or remediation network to facilitate patching, re-configuration, or other mitigations. (vii) CM.L3-3.4.3e Employ automated discovery and management tools to maintain an up-to-date, complete, accurate, and readily available inventory of system components. (viii) IA.L3-3.5.1e Identify and authenticate systems and system components, where possible, before establishing a network connection using bidirectional authentication that is cryptographically based and replay resistant. (ix) IA.L3-3.5.3e Employ automated or manual/procedural mechanisms to prohibit system components from connecting to organizational systems unless the components are known, authenticated, in a properly configured state, or in a trust profile. (x) IR.L3-3.6.1e Establish and maintain a security operations center capability that operates

(1) A request received by a DA activity having no records responsive to a request shall be referred to another DOD Component or DA activity, if the other Component or activity confirms that they have the requested records, or verifies that they are the proper custodian for that type of record. The requester will be notified of the referral. In cases where the DA activity receiving the request has reason to believe that the existence or nonexistence of the record may in itself be classified, that activity will consult the Component or activity having cognizance over the records in question before referring the request. If the Component or activity that is consulted determines that the existence or nonexistence of the records is in itself classified, the requester shall be so notified by the DA activity originally receiving the request that it can neither confirm nor deny the existence of the record, and no referral shall take place. (2) A DA activity shall refer a Privacy Act request for a classified record that it holds to another DOD Component, DA activity, or agency outside the Department of Defense, if the record originated in the other DOD Component, DA activity, or outside agency, or if the classification is derivative. The referring DA activity will provide the records and a release recommendation with the referral action. (3) Any DA activity receiving a request that has been misaddressed will refer the request to the proper address and advise the requester. (4) Within DA, referrals will be made directly to offices having custody of the requested records (unless the Denial Authority is the custodian of the requested records). If the office receiving the Privacy Act request does not know where the requested records are located, the office will contact the DA FOIA/P Office, to determine the appropriate office for referral. (5) The requester will be informed of the referral whenever records or a portion of records are, after prior consultation, referred to another activity for a release determination and direct response. Additionally, the DA activity referral letter will accomplish the following: (i) Fully describe the Privacy Act system of records from which the document was retrieved; and (ii) Indicate whether the referring activity claims any exemptions in the Privacy Act system of records notice. (6) Within the DA, an activity will refer a Privacy Act request for records that it holds but was originated by another activity, to the originating activity for direct response. An activity will not, in any case, release or deny such records without prior consultation with the originating activity. The requester will be notified of such referral.

A process to develop a Federal Information Processing Standard (FIPS) for Advanced Encryption Standard (AES) specifying an Advanced Encryption Algorithm (AEA) has been initiated by the National Institute of Standards and Technology (NIST). Earlier this year, candidate algorithms were nominated to NIST for consideration for inclusion in the AES. Those candidate algorithms meeting the minimum acceptability criteria have been announced by NIST and are available electronically at the address listed below. This notice solicits comments on the candidate algorithms from the public, and academic and research communities, manufacturers, voluntary standards organizations, and Federal, state, and local government organizations. These comments will assist NIST in narrowing the field of AES candidates to five or fewer for more detailed examination. It is intended that the AES will specify an unclassified, publicly disclosed encryption algorithm available royalty-free worldwide that is capable of protecting sensitive government information well into the next century.

Additionally, if modifications are adopted as proposed, the Security Rule would remain flexible and scalable by retaining broad standards with which regulated entities could comply in a variety of

ways. In 2003, the 13 implementation specifications that the Security Rule requires were considered so basic that no covered entity could effectively protect ePHI without implementing them. [286] While the Department agrees that these implementation specifications remain essential, we no longer believe that they are sufficient to address the risks to ePHI today. Rather, regulated entities must do more to ensure the confidentiality, integrity, and availability of ePHI today because of the changes in the environment in which health care is provided, how ePHI is maintained, the level of connectivity between information systems, and the technological sophistication of bad actors. We acknowledged in 2003 and again acknowledge here that there is no such thing as a totally secure system that carries no risks to security. [287] We posited at that time that Congress intended to set an exceptionally high goal for the security of [ePHI], while also recognizing that securing ePHI did not require that covered entities do so without regard for the cost. [288] However, we also made clear that a covered entity is required to implement adequate security measures and that cost was but one factor for a covered entity to consider when determining what constituted appropriate security measures. [289] As we noted, Cost is not meant to free covered entities from this responsibility. [290] In the 2013 Omnibus Rule, we further explained that [regulated entities] have the flexibility to choose security measures appropriate for their size, resources, and the nature of the security risks they face, enabling them to reasonably implement any given Security Rule standard. [. . .] Thus, the costs of implementing for [. . .] business associates will be proportional to their size and resources. [291] We continue to believe that this is the case. Additionally, as discussed above, there is a significant cost associated with breaches and unauthorized access financial, reputational (for both the individual and the regulated entity), and more. Thus, we believe that the standards and implementation specifications that we propose in this NPRM are the minimum that regulated entities should be doing to protect the security of ePHI and lower the costs associated with breaches and other incidents.

4. Small and Rural Health Care Providers Must Implement Strong Security Measures To Provide Efficient and Effective Health Care The statute requires that we consider the needs and capabilities of small health care providers and rural health care providers (as such providers are defined by the Secretary). [292]

(Comment 80) One comment notes that CBP's current requirements would apply to a trucking company transporting imported food into the United States and manifest data would be maintained. The comment states that FDA could easily coordinate with CBP to get the data from them in the event a threat to the nation's food supply is discovered, rather than develop its own distinct recordkeeping regulations. (Response) The Bioterrorism Act authorizes the Secretary (and, by delegation, FDA) to require the establishment and maintenance of records to address credible threats of serious adverse health consequences or death to humans or animals. As discussed in response to comment 79, subpart J of this final rule does not require duplication of existing records if those records contain all of the information required by subpart J. Therefore, to the extent information you keep for purposes of complying with CBP satisfies the provisions of subpart J, you do not need to keep duplicate records.

(Comment 81) One comment states that past situations have demonstrated that FDA already has a policy and good track record for finding and refusing adulterated products and products that could pose a problem to the American public. The comment questions how the final rule is going to improve upon existing recordkeeping. (Response) As explained in the proposed rule (68 FR 25188), FDA has been involved in traceback investigations where not all necessary records were established and maintained to enable FDA to conduct a complete tracing investigation. By issuing these regulations, FDA believes that the likelihood of such a situation recurring will be reduced. As discussed in response to comment 93 of this document, for those covered persons already establishing and maintaining records that contain all of the required information in subpart J of this final rule, duplication of those existing records is not necessary. (See response to comment 2 of this document for further discussion on FDA's past experiences with traceback failures.)

(Comment 82) Several comments recommend that, for accuracy and regulatory consistency, the final rule should recognize that compliance with the bill of lading regulations of DOT's FMCSA will constitute compliance with the transporter's obligations under proposed § 1.352. The comments note that bills of lading and freight/expense bills for motor carriers are legal documents and contain sufficient information for the agency to be able to fulfill its Bioterrorism Act responsibilities. The information to be included on the bill of lading and freight/expense bills is prescribed by the United States Department of Treasury at 49 CFR 373.101 and 373.103 .

concerning user privacy and security notices. One method of addressing this requirement is the use of a system-use notification banner that displays the legal requirements of using the system. Users may be required to click to agree to the displayed requirements of using the system each time they log on to the machine. This agreement can be used in the civil and/or criminal prosecution of an attacker that violates the terms. The legal notification should meet all applicable requirements. At a minimum, the notice should inform the user that:

- information system usage may be monitored or recorded, and is subject to audit;
- unauthorized use of the information systems is prohibited;
- unauthorized use is subject to criminal and civil penalties;
- use of the information system affirms consent to monitoring and recording;
- the information system contains CUI with specific requirements imposed by the Department of Defense; and
- use of the information system may be subject to other specified requirements associated with certain types of CUI such as Export Controlled information.

Example You are setting up IT equipment including a database server that will contain CUI. You have worked with legal counsel to draft a notification. It contains both general and specific CUI security and privacy requirements [a]. The system displays the required security and privacy information before anyone logs on to your organization's computers that contain or provide access to CUI [b].

Potential Assessment Considerations

- Are objectives identified for privacy and security notices, and does the implementation satisfy the required objectives [a,b]? Discrepancies may indicate a deficient process and/or an incomplete objective for the overall requirement.
- Are there any special requirements associated with the specific CUI category [a]? · Are appropriate notices displayed in areas where paper-based CUI is stored and processed [b]?

KEY REFERENCES · NIST SP 800-171 Rev. 2 3.1.9

3.3.3 | 3.3.3.3 Interface Specifications To help ensure consistently reliable access to ABAC services, all organizations that participate in information sharing through enterprise ABAC capabilities should fully understand the interface, interaction, and precondition requirements for all types of requests, including attribute and DP requests.

With a goal of developing exploitation and mitigation strategies, the Hardware Common Weakness Enumeration Special Interest Group (HW CWE SIG) has analyzed 108 different hardware weaknesses that originate from hardware design issues [6]. CWE categorizes and maintains hardware and software weaknesses separately, since they and their exploitation and mitigation techniques are fundamentally different. Additionally, the Common Attack Pattern Enumeration and Classification (CAPEC) established by the U.S. Department of Homeland Security [7] categorizes possible existing attack patterns in hardware, software, communications, supply chains, social engineering, and physical security. CAPEC also analyzes the likelihood of such attacks being launched, their potential severity and flow of execution, and the skills that an adversary is likely to need.

- A manufacturer may express a system's cybersecurity state through a Current Profile to report results relative to the Target Profile, or to compare with acquisition requirements. - A critical infrastructure owner/operator, having identified an external partner upon whom that infrastructure depends, may use the Target Profile to convey required cybersecurity outcomes. - A critical infrastructure sector may establish a baseline that can be used among its constituents as a sector-specific starting point from which to build tailored Target Profiles.

Industrial Control Systems (ICS), which include manufacturing systems, represent different types of control systems including supervisory control and data acquisitions (SCADA) systems, distributed control systems (DCS), and other control system configurations such as Programmable Logic Controllers (PLCs) often found in the industrial sectors and critical infrastructures. An ICS consists of combinations of control components (e.g., electrical, mechanical, hydraulic, and pneumatic) that act together to achieve an industrial objective (e.g., manufacturing, transportation of matter or energy). ICS support the large and diverse manufacturing industrial sector and can be categorized as either process-based, discrete-based, or a combination of both [3]. Manufacturing systems support the most critical and, sometimes, most sensitive operations and assets within an organization. The application of cybersecurity controls in these environments demands the greatest level of attention and effort to ensure that appropriate operational security and risk mitigation are achieved. The categorization process is the first step in the NIST Risk Management Framework (RMF) and provides organizations with information to support tailoring cybersecurity control implementation [3]. As defined by NIST Federal Information Processing Standard (FIPS) 199, the categorization process is based on the potential impact (e.g.

From the NIST SP 800-172 Rev 3 Final Public Draft: Data execution prevention safeguards can be

hardware- or software-enforced with hardware enforcement providing the greater strength of NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 mechanism. This requirement is sourced to a control tailored out of the SP 800-53B 2288

A commenter said the electric industry will experience increased costs as electric utilities comb through vast amounts of data across the electric grid to determine all potential CUI, even if that CUI is not specifically subject to a DoD contract. One commenter stated that guidance DoD has provided for electric utilities to identify CUI in the past is insufficient and suggested that use of Security Classifications Guides could help by minimizing the need for CMMC compliance. In addition, they speculated that inclusion of CMMC requirements could create requirements after award which might require adjustments to contract price. Another commenter stated energy companies servicing military customers must develop governance programs around data protection years in advance, with significant investments. The commenter is concerned that CMMC requires these companies to make these large investments prior to knowing if a proposed contract may contain CUI and without adequate guidance about what data is considered CUI. Response: This rule has no disproportionate impact on Native American-owned businesses. Once identified as a requirement, the CMMC Level will apply uniformly to all prospective competitors. DoD must enforce safeguarding requirements uniformly across the Defense Industrial Base for all contractors and subcontractors who process, store, or transmit CUI. The value of information (and impact of its loss) does not diminish when the information moves to DoD contractors and DoD subcontractors, regardless of their status as Native American or small disadvantaged businesses. The CMMC Program rule does not include threatened penalties. If a requirement of a DoD contract is not met, then standard contractual and other remedies applicable to that contract may apply. CMMC Program requirements make no change to existing policies for information security requirements implemented by DoD. Policies for CUI and creation of program documentation, to include Security Classification Guides, are separate from this rule. Section 170.4(b) of the rule states Defense Industrial Base (DIB) is defined in 32 CFR part 236 , which addresses DoD and DIB Cyber Security Activities. Section 236.2 includes the DoD approved definition for DIB. The CMMC Program applies only to DoD contracts that include the DFARS clause 252.204-7021 and under which FCI or CUI is processed, stored, or transmitted on contractor information systems. This includes CUI outside the category of the Defense Organizational Index Group. Contracts for the provision of electricity or other utilities which do not contain FAR clause 52.204-21 or DFARS clause 252.204-7012 and which do not require the processing, storing, or transmitting of FCI or CUI on contractor owned information systems will not require CMMC assessment. The CMMC rule makes no change to FAR cost allowability or cost accounting standards. The 32 CFR part 170

\$135,636,340 572 \$237,126 Option F \$119,792,995 621 \$192,903 (printed page 71645) Option H \$30,610,378 \$30,610,378 1,067 1,067 \$28,688 \$28,688 Option I \$106,138,020 1,072 \$99,009 Final Rule \$132,750,092 \$102,139,714 1,204 137 \$745,545 \$110,258 Adjusted Comprehensive \$244,134,086 \$111,383,994 1,282 78 \$1,428,000 \$190,432 The distribution of the number of illnesses averted due to faster traceback investigations and more successfully completed traceback investigations for each policy option are also reported in the following tables. Of the 800 annual food safety illnesses averted due to improved recordkeeping practices, about 600 can be attributed to more successfully completed tracebacks, and about 200 from faster tracebacks. The sum of averted illnesses from faster tracebacks, plus that from more successfully completed tracebacks may differ from that reported in the table of totals because of rounding in the computations. Table 19. All Averted (Reported and Unreported) Food Safety Illnesses per Year Mean Low High Adjusted Comprehensive 1,282 0 6,400 Option A 245 0 1,079 Option B 572 0 2,660 Option C 316 0 1,452 Option D 355 0 1,612 Option E 359 0 1,750 Option F 621 0 2,846 Final Rule 1,204 0 6,061 Option H 1,067 0 5,372 Option I 1,072 0 5,504 Table 20. Averted Annual Food Safety Illnesses From Faster Traceback Investigations Mean Low High Adjusted Comprehensive 451 0 2,692 Option A 83 0 513 Option B 206 0 1,278 Option C 111 0 691 Option D 122 0 755 Option E 124 0 763 Option F 184 0 1,078 Final Rule 425 0 2,532 Option H 387 0 2,307 Option I 396 0 2,414 (printed page 71646) Table 21. Averted Annual Food Safety Illnesses From More Successfully Completed Tracebacks Mean Low High Adjusted Comprehensive 826 0 3,024 Option A 161 0 605 Option B 364 0 1,296 Option C 203 0 778 Option D 232 0 864 Option E 234 0 864 Option F 434 0 1,728 Final Rule 775 0 2,592 Option H 676 0 2,592 Option I 673 0 2,592 The next table shows the food safety benefits as the number of averted illnesses valued by the low, middle, and high cost of illness estimates, and for the \$5 million and \$6.5 million estimates of the value of a statistical life. These are estimated annual food safety

benefits and should be interpreted as minimum benefits from this final rule because food security benefits are not included. Table 22. Value of Averted Food Safety Illnesses for the Final Rule

Low	Medium	High	VSL
1 = \$5 million	\$7,388,685	\$15,905,182	\$24,421,229
VSL = \$6.5 million	\$8,199,494	\$16,715,991	\$25,232,038

1 Value of a statistical life used to value the averted deaths. 2 A value of \$100,000 was used to value a year in good health. 3 A value of \$300,000 was used to value a year in good health. 4 A value of \$500,000 was used to value a year in good health. V. Final Regulatory Flexibility Analysis FDA has examined the economic implications of this final rule as required by the Regulatory Flexibility Act (5 U.S.C. 601-612

By limiting these exceptions to devices that have been updated and/or patched while they were supported by their manufacturer, we believe that this proposal would balance the interest in encouraging regulated entities to dispense with legacy devices with the cost of replacing such devices. Additionally, the Department believes that regulated entities should already have plans to replace legacy devices that cannot be made cybersecure because of their existing Security Rule obligations. We also recognize that at some point, most, if not all, devices will likely become legacy devices and that there may be legitimate reasons not to immediately replace them when the manufacturer ceases to provide support. In such cases, it will continue to be important for regulated entities to plan for how to address their ongoing Security Rule obligations. Finally, we propose an exception, proposed 45 CFR 164.312(b)(3)(iv)(C) , that would be available for a device authorized by the FDA for marketing pursuant to a submission received on or after March 29, 2023, where the device is supported by its manufacturer. We understand that the FDA considers security during the review of medical device marketing submissions, including those for software that is approved as a medical device, and works with device manufacturers to ensure that appropriate cybersecurity protections are built into such devices, pursuant to FDA's authority under the Consolidated Appropriations Act, 2023. [744] Thus, we do not believe it would be necessary or appropriate for the Security Rule to require encryption for an FDA-authorized medical device that has been authorized by the FDA for marketing pursuant to a submission received on or after March 29, 2023 where the device continues to be supported by its manufacturer. Where a proposed exception applies to the proposed encryption requirement, the Department also proposes to require that a regulated entity implement alternative measures and compensating controls. Specifically, we propose at proposed 45 CFR 164.312(b)(4)(i) to require a regulated entity to document the existence of an applicable exception and implement reasonable and appropriate compensating controls. Under the proposal, we would require documentation to occur in real-time, meaning when the criteria for the exception exist and at the time compensating controls are implemented. For example, a regulated entity disclosing ePHI to an individual by unencrypted email in accordance with the right of access would be required to document in accordance with the proposed 45 CFR 164.312(b)(4)(i) that: (1) before the disclosure, the individual has requested to receive ePHI by unencrypted email or unencrypted messaging technology; and (2) before the disclosure, the regulated entity informed the individual of the risks associated with transmission of unencrypted ePHI. The exception would not apply where such individual requests to receive access to their ePHI pursuant to 45 CFR 164.524

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 iv Reviewers are encouraged to comment on all or parts of SP 800-172, Revision 3 fpd. NIST 79 requests that all comments be submitted to 800-17 1comments@list.nist.gov by 11:59 p.m. Eastern Standard Time (EST) on November 14, 2025. Commenters are encouraged to use the comment template provided with the document announcement. Comments received in response to this request will be posted on the Protecting CUI project site after the due date. Submitters' names and affiliations (when provided) will be included, while contact information will be removed NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 v Call for

Promotion sequence number. (11) Awards and decorations. (12) Attendance at professional military schools. (13) Duty status at any given time. (14) Home of record (identification of the state only). (15) Length of military service. (16) Basic Pay Entry Date. (17) Official Photo. (B) All disclosures of personal information regarding military members (printed page 18772) shall be made in accordance with 32 CFR part 286 . (iii) Civilian employees not under the authority of OPM. (A) While it is not possible to identify categorically those items of personal information that must be released regarding civilian employees not subject to 5 CFR parts 293 , 294 , and 297 , such as nonappropriated fund employees, normally the following items may be released without a clearly unwarranted invasion of personal privacy: (1) Full name. (2) Grade or position. (3)

Date of grade. (4) Gross salary. (5) Present and past assignments. (6) Future assignments, if officially established. (7) Office or duty telephone numbers. (B) All releases of personal information regarding civilian personnel in this category shall be made in accordance with 32 CFR part 286. (6) When military or civilian personnel are assigned, detailed, or employed by the National Security Agency, the Defense Intelligence Agency, the National Reconnaissance Office, or the National Geospatial-Intelligence agency, information about such personnel may only be disclosed as authorized by Public Law 86-36 (National Security Agency-Officers and Employees) and 10 U.S.C. 424 (Disclosure of Organizational and Personnel Information: Exemption for Specified Intelligence Agencies). When military and civilian personnel are assigned, detailed or employed by an overseas unit, a sensitive unit, or to a routinely deployable unit, information about such personnel may only be disclosed as authorized by 10 U.S.C. 130b (Personnel in Overseas, Sensitive, or Routinely Deployed Units: Nondisclosure of Personally Identifying Information). (7) Information about military or civilian personnel that otherwise may be disclosable consistent with § 310.22(b)(5) may not be releasable if a requester seeks listings of personnel currently or recently assigned/detailed/employed within a particular component, unit, organization or office with the Department of Defense if the disclosure of such a list would pose a privacy or security threat. (c) Disclosures for established routine uses. (1) Records may be disclosed outside the Department of Defense pursuant to a routine use that has been established for the system of records that contains the records. (2) A routine use shall: (i) Be compatible with the purpose for which the record was collected; (ii) Identify the persons or organizations to whom the record may be released; (iii) Identify specifically the intended uses of the information by the persons or organization; and (iv) Have been published in the Federal Register (see § 310.32(i)).

implement the security requirements listed in § 170.14(c)(4) and table 1 to § 170.14(c)(4) within its Level 3 CMMC Assessment Scope as described in § 170.19(d). Successful implementation requires meeting all objectives defined in NIST SP 800-172A Mar2022 for the corresponding CMMC Level 3 security requirements. Requirements for ESPs and CSPs that process, store, transmit CUI are provided in § 170.18(c)(5) and (6). After implementation, the OSC must contact DCMA DIBCAC to perform an assessment to verify the implementation. DCMA DIBCAC will score the OSC using the scoring methodology provided in § 170.24. All objectives must be met in order for a security requirement to be considered fully implemented; in some cases, if not all objectives are met, some security requirements may be placed on a POA&M as defined in § 170.21. If the minimum score has been achieved and some security requirements are in a POA&M, the OSC has achieved the CMMC Status of Conditional Level 3 (DIBCAC); if all requirements are MET as defined in § 170.24(b), the OSC has achieved the CMMC Status of Final Level 3 (DIBCAC). For Conditional Level 3 (DIBCAC), a POA&M closeout must be conducted within 180 days as described in § 170.21(b) or the Conditional Level 3 (DIBCAC) CMMC Status will expire. After a Level 3 certification assessment, as well as after a POA&M closeout, DCMA DIBCAC will input the OSC's results into the CMMC instantiation of eMASS as described in § 170.18(a)(1)(i). After a Level 3 certification assessment, as well as after a POA&M closeout, the OSC must submit an affirmation as described in § 170.22. In order to be eligible for a contract with a requirement for the CMMC Status of Level 3 (DIBCAC), the OSC must have achieved the CMMC Status of either Conditional Level 3 (DIBCAC) or Final Level 3 (DIBCAC) and have submitted an affirmation. The Level 3 certification assessment must be completed every three years and the affirmation must be completed annually following the Final CMMC Status Date. Section 170.19-CMMC Scoping Section 170.19 addresses the requirements for the scoping of each CMMC Level and determines which assets are included in a given assessment and the degree to which each is assessed. The CMMC Assessment Scope is specified prior to any CMMC assessment, based on the CMMC Level being assessed. The Level 2 CMMC Assessment Scope may also be affected by any intent to achieve a CMMC Level 3 Certification Assessment, as detailed in § 170.19(e). Scoping for CMMC Level 1, as detailed in § 170.19(b), consists of all assets that process, store, or transmit FCI. These assets are fully assessed against the applicable CMMC security requirements identified in § 170.14(c)(2) and following the procedures in § 170.15(c). All other assets are out-of-scope and are not considered in the assessment.

(a) The contracting officer shall insert the clause at 52.204-2, Security Requirements for Classified Information, in solicitations and contracts when the contract may require access to classified information, unless the conditions specified in paragraph (d) of this section apply. (printed page 4292) (b) If a cost contract (see 16.302) for research and development with an educational institution is contemplated, the contracting officer shall use the clause with its Alternate I. (c) If a construction or architect-engineer contract under which employee

identification is required for security reasons is contemplated, the contracting officer shall use the clause with its Alternate II. (d) If the contracting agency is not covered by the NISP and has prescribed a clause and alternates that are substantially the same as those at 52.204-2, the contracting officer shall use the agency-prescribed clause as required by agency procedures. 4.403 Controlled unclassified information (CUI). 4.403-1 Definitions. As used in section 4.403· CUI Basic means the subset of CUI for which the authorizing law, regulation, or Governmentwide policy does not set out specific handling or dissemination controls. CUI Basic must be handled according to the uniform set of controls set forth in 32 CFR part 2002 and the CUI Registry. CUI Categories means those types of information for which laws, regulations, or Governmentwide policies require or permit agencies to exercise safeguarding or dissemination controls, and which has been listed in the CUI Registry. CUI Specified means the subset of CUI for which the authorizing law, regulation, or Governmentwide policy contains specific handling controls that it requires or permits agencies to use and that differ from those for CUI Basic. The CUI Registry indicates which laws, regulations, and Governmentwide policies include such specific requirements. Handling means any use of CUI, including but not limited to collecting, developing, receiving, transmitting, storing, marking, safeguarding, transporting, disseminating, reusing, and disposing of the information. Lawful Government purpose means any activity, mission, function, operation, or endeavor that the Government authorizes or recognizes as within the scope of its legal authorities or the legal authorities of non-executive branch entities such as State and local law enforcement. Limited dissemination control means any control identified on the CUI Registry that agencies may use to limit or specify CUI dissemination. On behalf of an agency means a contractor uses or operates an information system or maintains or collects information for the purpose of processing, storing, or transmitting Federal information, and those activities are not incidental to providing a service or product to the Government. 4.403-2 General. (a) Executive Order 13556

smart phones) in a manner that compromises the integrity of commercial and personal information. Such exploits are often launched through interactive Web sites that end users access online and through the use of external devices (e.g., portable USB drives, digital picture frames). While computer training and consumer education programs can reduce the amount of malware spread through these means by instructing users in safer online practices, there may be other mechanisms or systems that could prove effective in reducing such cyber risks. In Department of Commerce listening sessions, stakeholders identified improved Web site and component security as another area where modest technology investments might generate large improvements in the level of cybersecurity across the Internet. Should the government alone, the private sector, or the government and private sector collaboratively explore whether third-party verification of Web site and component security is or can prove effective in reducing the proliferation of malware? If so, what measures should be considered? What would be the implementation challenges in deploying such measures? 4. Authentication/Identity (ID) Management In our listening sessions, several stakeholders urged the Task Force to promote more widespread uptake of state-of-the-art authentication and ID management systems to reduce the incidents of successful cyber intrusions and attacks. Effective authentication and authorization systems establish a user's right to access resources. Many users currently rely on simple password systems for authentication. More sophisticated systems require multiple factors in the authentication process, for example, something the user knows, plus something that the user possesses (e.g., a physical credential or token). [20] (printed page 44221) The Department seeks comment on the effectiveness of current identity management systems in addressing cybersecurity risks. On June 25, 2010, the White House released the National Strategy for Trusted Identities in Cyberspace for public comment. This strategy promotes a set of options for enhancing on-line security and privacy so that individuals and organizations use trusted, interoperable identity solution as in a manner that promotes confidence, privacy, choice, and innovation to experience efficient and secure access to on line services. [21] Beyond the measures recommended in the National Strategy for Trusted Identities in Cyberspace,

Deploy technical controls to allow access to electronic protected health information only to those users and technology assets that have been granted access rights to the covered entity's or business associate's relevant electronic information systems as specified in §.164.308(a)(10). (viii) Maintenance. Review and test the effectiveness of the procedures and technical controls required by this paragraph (a)(2) at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. (b) Standard: Encryption and decryption ·(1) General. Deploy technical controls to encrypt and decrypt electronic protected health information using encryption that meets prevailing cryptographic

standards. (2) Implementation specification. Encrypt all electronic protected health information at rest and in transit, except to the extent that an exception at paragraph (b)(3) of this section applies. (3) Exceptions. This paragraph (b)(3) applies only to the electronic protected health information directly affected by one or more of the following exceptions and only to the extent that the covered entity or business associate documents that an exception applies and that all other applicable conditions are met. (i) The technology asset in use does not support encryption of the electronic protected health information consistent with prevailing cryptographic standards, and the covered entity or business associate establishes and implements a written plan to migrate electronic protected health information to a technology asset that supports encryption consistent with prevailing cryptographic standards within a reasonable and appropriate period of time. (ii) An individual requests pursuant to § 164.524 to receive their electronic protected health information in an unencrypted manner and has been informed of the risks associated with the transmission, receipt, and storage of unencrypted electronic protected health information. This exception does not apply where such individual will receive their electronic protected health information pursuant to § 164.524 and the technology used by the individual to receive the electronic protected health information is controlled by the covered entity or its business associate. (iii) During an emergency or other occurrence that adversely affects the covered entity's or business associate's relevant electronic information systems in which encryption is infeasible, and the covered entity or business associate implements reasonable and appropriate compensating controls in accordance with and determined by the covered entity's or business associate's contingency plan under § 164.308(a)(13). (iv) The technology asset in use is a device under section 201(h) of the Food, Drug, and Cosmetic Act, 21 U.S.C. 321(h) that has been authorized for marketing by the Food and Drug Administration, as follows:

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Department of the Army [Docket No. USA-2006-0011] 32 CFR Part 505 RIN 0702-AA53 AGENCY: Department of the Army, DoD. ACTION: Proposed rule; request for comments. SUMMARY: The Department of the Army is proposing to update policies and responsibilities for the Army Privacy Program, which implements the Privacy Act of 1974, by showing organizational realignments and by revising referenced statutory and regulatory authority, such as the Health Insurance Portability and Accountability Act and E-Government Act of 2002. DATES: Consideration will be given to all comments received by June 26, 2006. ADDRESSES: You may submit comments, identified by 32 CFR part 505 , Docket No. USA-2006-0011 and or RIN 0702-AA53, by any of the following methods: Federal eRulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. Mail: Federal Docket Management System Office, 1160 Defense Pentagon, Washington, DC 20301-1160. Instructions: All submissions received must include the agency name and docket number or Regulatory Information Number (RIN) for this Federal Register document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing on the Internet at <http://www.regulations.gov> as they are received without change, including any personal identifiers or contact information. FOR FURTHER INFORMATION CONTACT: Ms. Janice Thornton at (703) 428-6503. SUPPLEMENTARY INFORMATION: A. Background The Department of the Army's objective in revising 32 CFR part 505 is to reinforce Privacy Act policy objectives to include (1) restricting disclosure of personally identifiable records maintained; (2) to grant individuals rights of access to agency records maintained on themselves; (3) to grant individuals the right to seek amendment of agency records maintained on themselves upon a showing that the records are not accurate, relevant, timely, or complete; and (4) to establish practices ensuring the Army is complying with statutory norms for collection, maintenance, and dissemination of records. B. Executive Order 12866 (Regulatory Planning and Review)

MA.L2-3.7.1 · Perform Maintenance CMMC Assessment Guide · Level 2 | Version 2.13 144 Maintenance (MA) MA.L2-3.7.1 · PERFORM MAINTENANCE Perform maintenance on organizational systems. ASSESSMENT OBJECTIVES [NIST SP 800-171A]126 Determine if: [a] system maintenance is performed. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]126 Examine [SELECT FROM: System maintenance policy; procedures addressing controlled system maintenance; maintenance records; manufacturer or vendor maintenance specifications; equipment sanitization records; media sanitization records;

system security plan; other relevant documents or records]. Interview [SELECT FROM: Personnel with system maintenance responsibilities; personnel with information security responsibilities; personnel responsible for media sanitization; system or network administrators]. Test [SELECT FROM: Organizational processes for scheduling, performing, documenting, reviewing, approving, and monitoring maintenance and repairs for systems; organizational processes for sanitizing system components; mechanisms supporting or implementing controlled maintenance; mechanisms implementing sanitization of system components]. DISCUSSION [NIST SP 800-171 REV. 2]

From the NIST SP 800-172 Rev 3 Final Public Draft: Recovery and reconstitution operations reflect mission and business priorities; recovery point, NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 recovery time, and reconstitution objectives; and organizational metrics consistent 1360

According to security_rule_2003: Use your Visa or Master Card number and expiration date. Credit card orders can also be placed by calling the order desk at (202) 512-1800 or by faxing to (202) 5122250. The cost for each copy is \$10. As an alternative, you can view and photocopy the Federal Register document at most libraries designated as Federal Depository Libraries and at VerDate Jan<31>2003 many other public and academic libraries throughout the country that receive the Federal Register. This Federal Register document is also available from the Federal Register online database through GPO access, a service of the U.S. Government Printing Office. The Web site address is <http://www.access.gpo.gov/nara/index.html>. ## I. Background The Department of Health and Human Services (HHS) Medicare Program, other Federal agencies operating health plans or providing health care, State Medicaid agencies, private health plans, health care providers, and health care clearinghouses must assure their customers (for example, patients, insured individuals, providers, and health plans) that the integrity, confidentiality, and availability of electronic protected health information they collect, maintain, use, or transmit is protected. The confidentiality of health information is threatened not only by

AC.L2-3.1.13 · Remote Access Confidentiality CMMC Assessment Guide · Level 2 | Version 2.13 44
This requirement, AC.L2-3.1.13, requires the use of cryptographic mechanisms when enabling remote sessions and complements five other requirements dealing with remote access (AC.L2-3.1.12, AC.L2-3.1.14, AC.L2-3.1.15, IA.L2-3.5.3, and MA.L2-3.7.5): · AC.L2-3.1.12 requires the control of remote access sessions. · AC.L2-3.1.14 limits remote access to specific access control points. · AC.L2-3.1.15 requires authorization for privileged commands executed during a remote session. · IA.L2-3.5.3 requires multifactor authentication for network access to non-privileged accounts. · Finally, MA.L2-3.7.5 requires the addition of multifactor authentication for remote maintenance sessions. Example You are responsible for implementing a remote network access capability for users who access CUI remotely. In order to provide session confidentiality, you decide to implement a VPN mechanism and select a product that has completed FIPS 140 validation [a,b]. Potential Assessment Considerations · Are cryptographic mechanisms used for remote access sessions (e.g., Transport Layer Security (TLS) and Internet Protocol Security (IPSec) using FIPS -validated encryption algorithms) defined and implemented [a ,b]? Note that simply using an approved algorithm is not sufficient · the module (software and/or hardware) used to implement the algorithm must be separately validated under FIPS 140. KEY REFERENCES · NIST SP 800-171 Rev. 2 3.1.13

) or as authorized by the Contracting Officer. Additional controls other than NIST SP 800-171 Revision 2 may be specified in the contract's requirements document, in accordance with 32 CFR 2002.14(h)(2) , to address unique requirements to protect CUI Basic at higher than the moderate confidentiality level; (B) Comply with all additional security requirements for CUI Specified identified by the agency in the SF XXX; (C) Implement additional information security requirements the Contractor reasonably determines necessary to provide adequate security in a dynamic environment; (D) Comply with any requirements from NIST SP 800-172, Enhanced Security Requirements for Protecting Controlled Unclassified Information, identified by the agency. For any requirements in NIST SP 800-172 identified by the agency, the organizational defined parameters (ODP) provided in Attachment 1 of SF XXX shall be applied for applicable security requirements; (E) Ensure that, if the Contractor uses a cloud service provider to store, process, or transmit any CUI identified in SF XXX· (1) The cloud service provider meets security requirements established by the Government for the FedRAMP Moderate baseline (<https://www.fedramp.gov/documents/>); and (2) The additional requirements in paragraphs (d)(5)(ii)(B) and (C), and (g) of this clause are met; and (F) Submit the system security plan, and any associated plans of action required by NIST SP 800-171,

Revision 2, for any planned implementations or mitigations to the Government upon request to demonstrate the Contractor's implementation or planned implementation of the security requirements.

(e) Compliance. (1) The Contracting Officer may require the submission of supporting documentation to verify compliance with the contract's security requirements, or may require access to Contractor facilities or systems, as listed in SF XXX. (2) For applicable non-Federal information systems, the agency may conduct validation actions in accordance with NIST SP 800-171A, Assessing Security Requirements for Controlled Unclassified Information and, if applicable, NIST SP 800-172A, (printed page 4299) Assessing Enhanced Security Requirements for Controlled Unclassified Information. (f) Training. (1) General CUI training. All Contractor employees who will handle CUI shall complete general CUI training before doing so, and periodically complete refresher training thereafter, as described in the training sections at Section II of Part B and Section III of Part C of the SF XXX. The Contractor shall maintain documentation of employee training and shall provide it to the Contracting Officer upon request. (2) Additional training. Additional agency-specific training.

The Defense Counterintelligence and Security Agency (DCSA), as the DoD designated NISP cognizant security office, has collected information about baseline costs using an OMB-approved information collection process employing statistical methods for contractors' NISP implementation (OMB Control Number 0704-0458, Industry Cost Collection Report Survey). The most recent data collected by DCSA on contractors' NISP implementation costs are for fiscal year (FY) 2017 and reported in the ISOO 2017 annual report to the President. DCSA has used this survey collection methodology for contractors' NISP implementation under DoD security cognizance for over 11 years. A NISP government and industry working group developed the survey in 1995 and predecessor office to the OUSD(I&S) initially ran the annual survey. The Information Security Oversight Office (ISOO) placed a moratorium on conducting this survey after 2017 until a new NISP survey methodology is developed. DCSA began the costs analysis for the baseline costs for fiscal year 2017 by randomly selecting active NISP contractor facilities that have existing DoD approval for classified storage at their own physical locations and having those facilities submit security costs. The randomly selected contractor facilities also have an active facility security clearance and a permanent Commercial and Government Entity (CAGE) Code. In addition to the randomly selected cleared facilities having approved classified storage, DCSA categorizes these contractor facilities for the survey based on the size, scope, and complexity of each contractor's security program. The general methodology used to estimate security costs incurred by contractor cleared facilities with approved storage of classified information is based on the costs incurred by respondent contractors for the protection of classified information. The methodology captures the most significant portion of industry's costs, which is labor. Security labor in the survey is defined as personnel whose positions exist to support operations and staff in the implementation of government security requirements for the protection of classified information. Guards who are required as supplemental controls are included in security labor. The respondent contractors are requested to compile their cleared facility's current annual security labor cost in burdened, current year dollars with the most recent data being from the 2017 survey. The labor cost, when identified as an estimated percent of each contractor's total security costs, enables the respondent contractors to calculate their total security costs. Information collected is compiled to create an aggregate estimated cost of NISP classification-related activities. Only the aggregate data is reported. There is a 95% confidence that the full enterprise industrial security total baseline cost does not exceed \$1.486 billion for fiscal year 2017. NISP cost estimates (2017) Benefits of NISP rule

Three commenters viewed CMMC's intent to store CMMC related data in an existing DoD system, SPRS, as an indication that SPRS would replace other DoD risk tracking systems or the risk monitoring responsibilities of other agencies. One commenter asked whether other Services would have their own systems, as the SPRS Program Office is within the Navy. Another comment stated CMMC and SPRS should not be tasked with the responsibility of addressing Supply Chain Risk Management (SCRM). One comment asked if the DoD intended to make CMMC Level 2 and 3 certification information available to other agencies, which could reduce the cost burden of compliance with assessment/certification programs adopted by other agencies. One comment asked how PII would be protected in SPRS. Another comment asked for SPRS to be redesigned to list assessment results for each security requirement instead of the aggregate level. One comment asked for a CMMC-specific process for entering data into SPRS to make it easier for small businesses and another comment asked for vendor visibility into a potential sub-contractor's SPRS score. Several comments asked about the CAGE code requirement and noted a perception that businesses outside the U.S are unable to obtain a CAGE or become a member of PIEE

and therefore unable to access SPRS. One comment asked whether each contract would require a new SPRS entry. One comment asked if OSCs that already have an eMASS account would be able to access the CMMC instantiation of eMASS and one comment questioned the cost/benefit of entering pre-assessment data into eMASS. Another comment asked for clarification on the roles and responsibilities of DoD Program Managers regarding the data uploaded into eMASS. One commenter suggested that eMASS be modified to permit tracking of self-assessment, in addition to certification assessments. Response: SPRS is used to provide CMMC Status, score results, and affirmation status to contracting officers and program managers as part of the contract award process. It does not supersede other DoD program office risk register systems. SPRS will be used for reporting CMMC Status of all contractors, regardless of which service issued the contract. Although the SPRS program is managed by the Department of the Navy, its use spans across the Department. There is no role for other agencies associated with this CMMC rule, which applies only to DoD contractors that process, store, or transmit FCI or CUI. The CMMC PMO has no current agreements with other Federal agencies to share CMMC assessment results. There is nothing that prevents an OSA from sharing their CMMC Status with other entities.

Compliance with NIST Guidelines 28 19,600,000 12,000,000 Annual Assessments 27 6,600,000 6,600,000 Continuous Monitoring Strategy 28 408,000 N/A Develop and Maintain OT List 28 204,000 102,000 Binding Operational Directives and Emergency Directives 28 3,640,000 840,000 FEDRamp Compliance 53 46,000,000 32,000,000 Totals 76,635,700 51,543,000 C. Government Compliance Requirements The total estimated annualized costs to the Government associated with this FAR rule over a ten-year period are approximately \$136,000 (calculated at a 7-percent discount rate). The following specific compliance requirements related to FAR clause 52.239-XX and 52.239-YY are tasks for the Government: 1. Review and Analyze Annual Assessments The Government must review and analyze each of the 54 assessments provided by contractors annually (see 39.X03(c)) and provide a recommendation to the contractor to implement, or a rationale for not implementing, each recommendation in the contractor's assessments. It is estimated that a General Schedule (GS) 15/step 5 employee will spend 20 hours reviewing, analyzing, and drafting recommendation responses for each assessment. The wage rate of a GS 15/step 5 employee is \$74.35 per hour, according to the Office of Personnel Management (OPM) 2023 GS Locality Pay Table for the rest of the United States (https://www.opm.gov/policy-data-oversight/pay-leave/salaries-wages/salary-tables/pdf/2023/RUS_.h.pdf). A factor of 36.25 percent, based on OMB M-08-13, Update to Civilian Position Full Fringe Benefit Cost Factor, is applied to the average wage rate to account for total employee benefits paid for by the Government ($\$74.35 * 1.3625 = \101.30), and a factor of 12 percent is then applied to the rate of \$101.30 to account for overhead, which results in a loaded rate of \$113.46 ($\$101.30 * 1.12$). Based on the discussion above, the total annual estimated cost for the Government to review, analyze, and (printed page 68411) respond to 54 annual assessment submissions each year is approximately \$122,537 (54 responses * 20 hours * \$113.46). 2. Review List of Operational Technology Equipment Upon submission, the Government must review approximately six lists of OT equipment submitted by contractors each year (see 39.X03(k)). It is estimated that a GS 15/step 5 employee will spend 20 hours reviewing, analyzing, and processing a contractor's submission. Using an average loaded wage rate of \$113.46 for GS Schedule 15/step 5 employees, the total annual estimated cost for the Government to review, analyze, and file six OT equipment list submissions each year is approximately \$13,615 (6 responses * 20 hours * \$113.46). 3. Review Continuous Monitoring Strategy

mation: A Supplement to NIST Special Publication 800-171 (SP 800-172) offers additional recommendations for handling CUI in situations where that information runs a higher than usual risk of exposure. The enhanced security requirements protect the confidentiality, integrity, and availability of CUI from APTs by promoting penetration-resistant architectures, damage-limiting operations, and designs to help achieve cyber resiliency and survivability. NIST also issued Assessing Enhanced Security Requirements for CUI (draft SP 800-172A) to assist organizations with planning and conducting efficient, effective, and cost-effective assessments of the enhanced security requirements in SP 800-172.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 INTENDED EFFECT IMPACT ON RISK EXPECTED RESULTS Expunge Remove resources that are known to be or are suspected of being unsafe, incorrect, or corrupted. Reduce the likelihood of impact of subsequent events in the same threat scenario. · A malfunctioning, misbehaving, or suspect resource is restored to normal operation.

· The adversary loses a capability for some period as adversary- directed threat mechanisms (e.g., malicious code) are removed. · Adversary-controlled resources are so badly damaged that they cannot perform any function or be restored to a usable condition without being entirely rebuilt.
Example: The defender uses virtualization to refresh critical

CIS Safeguard 3.11 · Encrypt Sensitive Data At Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data. Implementation Groups: 2,3 Asset Type: data Security Function: protect Parent Control: Data Protection

, is limited to a small number of U.S. cleared legal entities in the NISP for which the ultimate parent entity and any intermediate parent entities of such subsidiary are located in a country that is part of the NTIB; and that is subject to the FOCI requirements of the NISP. There are currently 20 U.S. cleared legal entities with their associated cleared divisions, subsidiaries or branch (estimated to be another 100 cleared entities) to whom Section 842 of Public Law 115-232 applies. Section 881 of Public Law 114-328 expanded the legal definition of the NTIB to include the United Kingdom and Australia. The NTIB is comprised of the United States, the United Kingdom of Great Britain and Northern Ireland, Canada and Australia. NTIB is based on the principle that defense trade between the United States and its closest allies enables a host of benefits, including increased access to innovation, economies of scale, and interoperability (10 U.S.C. 2500). Section 842 of Public Law 115-232 is deregulatory by statute and this rule. There are no estimated costs to the small number of entities impacted because they are required already to submit any new or change to FOCI information for their initial and continued FCL, respectively, via the SF 328, Certificate Pertaining to Foreign Interests in the NISP as do all other U.S. cleared legal entities. 32 CFR part 2004 provides a CSA up to 30 days to assess the submitted NID and then another 30 days for a controlling agency to make a NID for the type of proscribed information under the purview of each (ODNI for SCI, DOE for RD or NSA for COMSEC). Thus, with Section 842 of Public Law 115-232 , there has been minimum 60 day delay for a NID involving an NTIB covered entity which has impacted the timeliness of contract performance. There are estimated costs savings as this small number of cleared entities and their entity cleared employees designated to work on specific classified contracts involving proscribed information will no longer have to wait at least 60 days for NIDs after contract award for access to proscribed information when all other requirements have been met for access to classified information and contract performance. Using the published Office of Personnel Management GS salary schedule for FY20, the labor rate for an FSO and an estimated 8 cleared employees in each of the 2 small business entities impacted is the equivalent of a GS11 step 5 with a time savings of 320 hours for each year 1 through 20. The labor rate for an FSO and an estimated 19 cleared employees in each of the 18 large business entities impacted is the equivalent of a GS13 step 5 with a time savings of 320 hours for each year 1 through 20. These assumptions imply cost savings of \$11.81 million in each year. C. USG Cost Analysis of the Changes to the Baseline From This Rule 1. Projected USG Cost/Cost Savings.

DFARS 252.204-7008 (Compliance with Safeguarding CDI Controls) Requires offerors to represent that they will implement NIST SP 800-171 security requirements. Contractors should review the full text of DFARS 252.204-7008 in conjunction with their contracting officer and legal counsel to ensure full compliance. The clause should be read alongside the CMMC requirements at 32 CFR Part 170.

The Congressional Review Act, 5 U.S.C. 801 et seq., as amended by the Small Business Regulatory Enforcement Fairness Act of 1996, generally provides that before a rule may take effect, the agency promulgating the rule must submit a rule report, which includes a copy of the rule, to each House of the Congress and to the Comptroller General of the United States. We will submit a report containing this rule and other required information to the U.S. Senate, the U.S. House of Representatives, and the Comptroller General of the United States. A major rule cannot take effect until 60 days after it is published in the Federal Register . This final rule is a ·major rule· as defined by 5 U.S.C. 804(2) because it is also economically significant under section 3(f) of E.O. 12866 with an annual effect on the economy of \$100 million or more. Sec. 202, Public Law 104-4 , ·Unfunded Mandates Reform Act· Section 202 of the Unfunded Mandates Reform Act of 1995 (UMRA) (2 U.S.C. 1532) requires agencies to assess anticipated costs and benefits before issuing any rule whose mandates require spending in any 1 year of \$100 million in 1995 dollars, updated annually for

inflation. This final rule will not mandate any requirements for State, local, or tribal governments, nor will it affect private sector costs. Public Law 96-511, Paperwork Reduction Act (44 U.S.C. Chapter 35) It has been determined that 32 CFR part 117 does impose reporting or recordkeeping requirements under the Paperwork Reduction Act of 1995. DoD is not proposing changes to the DoD collections based on this final rule, nor have any of the other NISP CSAs indicated proposed changes based on this rule. The DOE and NRC have collections based on their respective authorities as a NISP CSA; but neither has a collection for a Contract Security Classification Specification because DOE and NRC each complete that specification for both prime contracts and subcontracts. By accepting the contract, the contractor obligates itself to fulfill the requirements specified in applicable DOE Acquisition Regulation (DEAR) clauses (available at <https://www.energy.gov/management/downloads/searchable-electronic-department-energy-acquisition-regulation>) and identified DOE Directives. The DOE Directives contain a contractor requirements document that conveys security obligations and the statutes for civil penalties for security violations. The Nuclear Regulatory Commission Acquisition Regulation part 2052.204-70 includes the security requirements levied on the contractor (available at https://www.acquisition.gov/nrcar/nrcar-part-2052-solicitation-provisions-and-contract-clauses#P41_1774). For ease of review of this rule, the collections are discussed below. Materials associated with all of the collections can reviewed at www.reginfo.gov . OMB Control Number 0704-0194, DD Form 441, DoD Security Agreement. OMB Control Number: 0704-0571, National Industrial Security System,

(Response) FDA agrees with the comments in part. Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food are subject to §§ 1.361 and 1.363 of this final rule (records access for existing records) with respect to its packaging (the outer packaging of food that bears the label and does not contact the food). All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import packaging are excluded from all of the requirements of subpart J of this final rule. In addition, persons who place food directly in contact with its finished container are subject to all of the requirements of subpart J as to the finished container that directly contacts that food. All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that directly contacts the food are excluded from the requirements of subpart J as to the finished container, except §§ 1.361 and 1.363 of this final rule. For example, a manufacturer and transporter of candy bar wrappers are not required to establish and maintain records as to the wrappers because they do not place food (candy bars) directly in contact with its finished container (wrappers). A manufacturer of candy bars, who places the candy bars in the wrappers, is required to keep records as to the sources of the wrappers and the recipients of the candy bars as a whole (not the candy bar and wrapper separately). Once the candy bar is placed in the wrapper, all persons who manufacture, process, pack, transport, distribute, receive, hold, or import the wrapped candy bar are required to keep records of the wrapped candy bar, but not to keep separate records with respect to the wrapper. FDA notes that the food in contact with the finished container refers to articles used by people in the ordinary way that most people use food primarily for taste, aroma, or nutritive value and not all substances defined as food by section 201(f) of the FD&C Act. The requirements for packaging and food contact substances are reflected in the following table. Table B. Packaging and Food Contact Substances

SUBSTANCE	ACTIVITY	COVERAGE
Packaging (Defined as the outer packaging of food that bears the label and does not contact the food. Packaging does not include food contact substances (§ 1.328).	Manufacture, process, pack, transport, distribute, receive, hold, or import	Excluded from all provisions of the rule unless person also engages in covered activity with respect to food, in which case subject to §§ 1.361 and 1.363 (record access) (See § 1.327(i))
Food contact substance, other than the finished container that directly contacts food	Manufacture, process, pack, transport, distribute, receive, hold, or import	Excluded from all provisions of the rule, except §§ 1.361 and 1.363 (record access) (See § 1.327(j))
Finished container that contacts food	Place food directly in contact with its finished container	

Audit and Evaluation of Computer Security II: System Vulnerabilities and Controls ## Audit and Evaluation of Computer Security II: System Vulnerabilities and Controls NATIOIVAX. The National Bureau of Standards, with the support of the U.S. General Accounting Office, sponsored a second invitational workshop on computer security audit, entitled "Audit and Evaluation of Computer Security II: System Vulnerabilities and Controls," In Miami Beach, Florida, on November 28-30, 1978. A cross-section of highly qualified people In the computer science and EDP audit fields was assembled to develop material that would be directly usable for a Federal Information Processing

Standard (FTPS) Guideline on the subject. In order to cover the material in a systematic fashion, the workshop was partitioned into three management sessions and five technical sessions. The management sessions addressed Managerial and Organizational Vulnerabilities and Controls at the Staff Level (1 session) and the Line Level (2 sessions). The technical sessions addressed vulnerabilities and controls in the areas of Terminal and Remote Peripherals, Communication Components, Operating Systems, Applications and Non- Integrated Data Files, and Data Base/ Data Base Management Systems. These Proceedings are the reports developed by the eight sessions of the workshop.

The report specifically noted that the audit results were consistent with the findings of OCR's compliance reviews and complaint investigations. [244] Recent enforcement actions provide evidence that the results of the 2016-2017 audits were not isolated cases. In 2023, OCR entered into seven resolution agreements with regulated entities after investigations indicated that they had potentially violated the Security Rule, constituting almost half of the total resolution agreements OCR entered into that year. [245] In each case, OCR's investigation found evidence of multiple potential violations. For example, in one case, a regulated entity did not detect an intrusion into its network until 20 months later when its files were encrypted with ransomware. [246] OCR's investigation found evidence of potential failures of the regulated entity to conduct a risk analysis or to sufficiently monitor information system activity. OCR also found evidence that the regulated entity may not have had policies and procedures in place to implement the requirements of the Security Rule to protect the confidentiality, integrity, and availability of ePHI. [247] As another example, an OCR investigation of a large health care system found indications of multiple potential violations of the Security Rule, including failures by the regulated entity to conduct a risk analysis, monitor and safeguard its electronic information systems, and implement policies and procedures to record and examine activity in its electronic information systems containing ePHI. [248] The regulated entity was not only unable to prevent the cyberattack, but it was unaware the attack had occurred until two years later. This is despite the long-standing requirements of the Security Rule and the obligations imposed on regulated entities for risk analysis and risk management. Despite the long-standing nature of the Security Rule and the proliferation of guidance documents from NIST, the Department, CISA, FTC, and others, regulated entities continue to fail to implement reasonable and appropriate security measures as required by the Security Rule. [249] For example, the Security Rule and NIST guidance have addressed encryption for data in transit and at rest for many years. [250] And yet, in the 2021 survey of health care cybersecurity professionals, only half of the respondents reported having implemented encryption for data in transit across the enterprise. [251] Similarly, according to its CEO, a large covered entity failed to deploy multi-factor authentication (MFA) throughout its enterprise and experienced a significant breach. [252] If this is accurate, it would run counter to long-standing provisions in both the Security Rule and NIST guidance; the Security Rule has required the implementation of appropriate access controls since 2003 and NIST recommends similar controls. [253]

(Response) To the extent that a purchase order contains all required identifiers of food received or released, the purchase orders may be used to satisfy the requirement. To the extent that a purchase order only contains some of the required information, those records will need to be supplemented to satisfy all the requirements contained in §§ 1.337 and 1.345 of this final rule. FDA notes that the final rule only requires that persons who manufacture, process, or pack food maintain lot or code number or other identifier of the food, and only requires this information to the extent that the information exists. Furthermore, FDA is not specifying the form or the format of the information that is required to be established and maintained. (Comment 115) One comment states the FDA should standardize lot codes. (Response) FDA does not agree. The agency has determined that the least burdensome way of issuing the recordkeeping requirements mandated by the Bioterrorism Act is to specify the information that must be contained in the records, but not the format in which the records are kept. As indicated by other comments summarized previously, persons subject to this final rule already have various means to identify food, including lot numbers. The final rule allows such persons to use lot numbers or other appropriate identifiers, including abbreviations, provided such information can readily be decoded to identify particular foods if FDA makes an appropriate request to access records. 7. Quantity and How the Food is Packaged (Comment 116) A few comments recommend that FDA allow quantity of products in bulk containers to be expressed in gross quantity, e.g., 1 to 5,000 gallon (gal) tank load; 5 to 1,000 gal totes. (Response) FDA agrees with this comment that, when recording quantity of bulk food, the gross quantity, or weight, (e.g., 5,000 gal)

is acceptable. To satisfy the requirement to record how the food is packaged, ·tank load· or ·totes· is acceptable. FDA has revised §§ 1.337(a)(5) and 1.345(a)(5) of this final rule accordingly. (Comment 117) One comment representing warehouses recommends that the final rule require that the information relating to quantity and how a food is packaged be maintained by the warehouse customer. (Response) FDA disagrees with this comment. Warehouses ·hold· food and are, therefore, subject to all of the regulations in subpart J of this final rule. The comment has not explained why a warehouse would not know or could not obtain information regarding the quantity of food received and how it is packaged. FDA believes it is necessary to maintain this information at each step of the distribution chain to be able to effectively and efficiently conduct a tracing investigation. 8. Name, Responsible Individual, Address, Telephone Number, Fax Number, E-Mail Address of Transporters Who Transported the Food To You and From You

AU.L2-3.3.9 · Audit Management CMMC Assessment Guide · Level 2 | Version 2.13 89 AU.L2-3.3.9 · AUDIT MANAGEMENT Limit management of audit logging functionality to a subset of privileged users. ASSESSMENT OBJECTIVES [NIST SP 800-171A]78 Determine if: [a] a subset of privileged users granted access to manage audit logging functionality is defined; and [b] management of audit logging functionality is limited to the defined subset of privileged users. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A] Examine [SELECT FROM: Audit and accountability policy; access control policy and procedures; procedures addressing protection of audit information; system security plan; system design documentation; system configuration settings and associated documentation; access authorizations; system-generated list of privileged users with access to management of audit logging functionality; access control list; system audit logs and records; other relevant documents or records]. Interview [SELECT FROM: Personnel with audit and accountability responsibilities; personnel with information security responsibilities; system or network administrators; system developers]. Test [SELECT FROM: Mechanisms managing access to audit logging functionality]. DISCUSSION [NIST SP 800-171 REV. 2]

Multiple commenters pointed out that the rule does not specify an authoritative source for obtaining a CMMC certificate, leaving the pedigree of certificates in question. Two comments inquired about the security of record [data] collection and retention and whether the assessors' platforms would need to be CMMC Level 3 compliant to protect sensitive data used for the assessment/certification process. Response: The processes for achieving compliance with a CMMC level are described in § 170.15 through § 170.18. CMMC Level 2 Certification Assessments are conducted by C3PAOs authorized by the CMMC Accreditation Body. C3PAOs grant CMMC Level 2 certificates of assessment. The DoD conducts CMMC Level 3 Certification Assessments and grants Level 3 certificates of assessment. A C3PAO's IT infrastructure must achieve at least a CMMC Level 2 Certification Assessment. Certified CMMC Assessors working at their place of business or from home must use their C3PAO's IT infrastructure. Assessment data and results are securely uploaded by the C3PAO into the CMMC instantiation of eMASS. The CMMC instantiation of eMASS automatically feeds compliance data into SPRS. Both eMASS and SPRS are Department owned and operated systems. Comment: A few commenters requested resources for understanding CMMC requirements. There were also many comments related to the purpose, status, schedule, or content of the CMMC Assessment Guides. Additional comments requested clarification on the evaluation criteria and evidence described in the current Assessment Guides. Response: CMMC Assessment Guides are optional resources to aid in understanding CMMC requirements and are largely derived from NIST documentation, to include NIST SP 800-171 Rev 2 and NIST SP 800-172. The CMMC assessment process is defined in § 170.15 through § 170.18, and the CMMC Scoring Methodology is defined in § 170.24. The evaluation criteria (i.e., assessment procedures) and evidence (i.e., potential assessment methods and objects) required are taken directly from the NIST documentation, and revisions to NIST documentation are outside the scope of this rule. The CMMC Assessment Guides provide supplementary information, further discussion, examples, and references for assessors and contractors preparing for assessments. The guides do not identify (printed page 89076) specific solutions or baselines. These documents are available at: <https://DoDcio.defense.gov/CMMC/>. Updated CMMC Assessment Guides and associated CMMC documents were posted on the OUSD(A&S) CMMC website after the public comment period for DFARS Case 2019-D041 closed on November 30, 2020. These documents reflected changes based on review of public comments. Future updates to CMMC guidance documentation will be made as needed. Comment:

e. With respect to the definitions of ·information system· and ·electronic information system·, the extent of a business associate's direct management control over applications in cloud computing environments, where the business associate is the cloud service provider. f. Whether defining the

term ·technical controls· and adding it to the definition of ·technical safeguards· would more clearly explain the requirements of 45 CFR 164.312 . g. Whether defining ·implement· and ·deploy· as we propose would more clearly explain the differences between what is expected of regulated entities with respect to administrative and physical safeguards and technical safeguards. To the extent that the proposals would not clarify the differences, please provide alternative solutions.

C. Section 164.306·Security Standards: General Rules 1. Current Provisions Section 164.306 applies to regulated entities and includes the general rules for security standards. Generally, paragraph (a) codifies HIPAA statutory requirements for safeguarding ePHI. [406] Under these rules, regulated entities are required to do all of the following: Ensure the confidentiality, integrity, and availability of all ePHI the regulated entity creates, receives, maintains, or transmits. [407] Protect against reasonably anticipated threats or hazards to the security or integrity of such information. [408] Protect against any reasonably anticipated uses or disclosures of such information not permitted by the Privacy Rule. [409] Ensure that workforce members comply with the Security Rule. [410] Paragraph (b) of this section permits regulated entities to determine the most (printed page 931) appropriate security measures for protecting ePHI and their information systems. Accordingly, 45 CFR 164.306(b)(1) permits regulated entities to use any security measures to reasonably and appropriately implement the standards and implementation specifications of the Security Rule, while 45 CFR 164.306(b)(2) contains the factors that regulated entities are to consider when deciding which security measures to use. This paragraph furthers the aim of HIPAA's requirement for the security standards to take into account certain factors by providing for their consideration by regulated entities. [411] Accordingly, 45 CFR 164.306(b)(2) directs regulated entities to take these factors into account when determining the manner in which they will comply with the security standards and implementation specifications. Section 164.306(c) requires regulated entities to comply with the administrative, physical, and technical safeguard standards in sections 45 CFR 164.308 , 164.310 , and 164.312 respectively, and with standards for organizational requirements and policies, procedures, and documentation requirements in sections 45 CFR 164.314 and 164.316

On July 30, 1993, notice was published in the Federal Register (58 FR 40791) that a Federal Information Processing Standard for EES was being proposed for Federal use. The written comments submitted by interested parties and other material available to the Department relevant to this standard were reviewed by NIST. On the basis of this review, NIST recommended that the Secretary approve the standard as a Federal Information Processing Standards Publication and prepared a detailed justification document for the Secretary's review in support of that recommendation. The detailed justification document which was presented to the Secretary is part of the public record and is available for inspection and copying in the Department's Central Reference and Records Inspection Facility, room 6020, Herbert C. Hoover Building, 14th Street between Pennsylvania and Constitution Avenues, NW., Washington DC 20230. This FIPS contains two sections: (1) An announcement section, which provides information concerning the applicability, implementation, and maintenance of the standard; and (2) a specifications section which deals with the technical requirements of the standard. Both sections of the standard are provided in this notice.

CIS Safeguard 16.5 · Use Up-to-Date and Trusted Third-Party Software Components Use up-to-date and trusted third-party software components. When possible, choose established and proven frameworks and libraries that provide adequate security. Acquire these components from trusted sources or evaluate the software for vulnerabilities before use. Implementation Groups: 2,3 Asset Type: applications Security Function: protect Parent Control: Application Software Security

- Securely Provision (SP): Risk Management (RSK), Systems Architecture (ARC), Systems Development (SYS) - Operate and Maintain (OM): Data Administration (DTA), Network Services (NET), Systems Administration (ADM), Systems Analysis (ANA) - Oversee and Govern (OV): Cybersecurity Management (MGT), Executive Cyber Leadership (EXL), Program/Project Management (PMA) and Acquisition - Protect and Defend (PR): Cybersecurity Defense Analysis (CDA), Cybersecurity Defense Infrastructure Support (INF), Incident Response (CIR), Vulnerability Assessment and Management (VAM) - Investigate (IN): Digital Forensics (FOR) The publication provides insights to inform organizations' risk management processes. After reading this publication, an organization should be able to improve the quality of its risk assessments for IoT devices and its response to the identified risk through the lens of cybersecurity and privacy. However, this does not mean cybersecurity and privacy risks for an IoT device can all be addressed within the device itself. Every IoT device operates within a broader IoT environment where it interacts with other IoT and non-IoT devices, cloud-based services, people, and

other components. Cybersecurity risk and privacy risk are related but distinct concepts. Risk is defined in NIST SP 800-37 Revision 2 as 'a measure of the extent to which an entity is threatened by a potential circumstance or event, and typically is a function of: (i) the adverse impact, or magnitude of harm, that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence.' [4] For cybersecurity, risk is about threats-the exploitation of vulnerabilities by threat actors to compromise device or data confidentiality, integrity, or availability.

A manager (MGMT2) for 32 hours ($\$95.96/\text{hr} \times 32\text{hrs} = \$3,071$) A staff IT specialist (IT4) for 72 hours ($\$97.49/\text{hr} \times 72\text{hrs} = \$7,019$) A senior IT specialist (IT3) for 72 hours ($\$81.96/\text{hr} \times 72\text{hrs} = \$5,901$) An IT specialist (IT2) for 120 hours ($\$54.27/\text{hr} \times 120\text{hrs} = \$6,512$) Phase 3: Reporting of certification assessment results: \$2,712 A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) A manager (MGMT2) for 4 hours ($\$95.96/\text{hr} \times 4\text{hrs} = \384) A staff IT specialist (IT4) for 16 hours ($\$97.49/\text{hr} \times 16\text{hrs} = \$1,560$) A senior IT specialist (IT3) for 0.08 hours ($\$81.96/\text{hr} \times 0.08\text{hrs} = \7) Affirmations: initial affirmation post assessment: \$2,712 C3PAO Costs: C3PAO engagement inclusive of Phases 1, 2, and 3 (5-person team) for 200 hours ($\$260.28/\text{hr} \times 200\text{hrs} = \$52,056$) Reaffirmations: It is estimated that the costs to reaffirm a Level 2 certification assessment annually is \$2,712 (three-year cost is \$8,136 or $\$2,712 \times 3$) A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) A manager (MGMT2) for 4 hours ($\$95.96/\text{hr} \times 4\text{hrs} = \384) A staff IT specialist (IT4) for 8 hours ($\$97.49/\text{hr} \times 8\text{hrs} = \$1,560$) A senior IT specialist (IT3) for 0.08 hours ($\$81.96/\text{hr} \times 0.08\text{hrs} = \7) The Level 2 affirmations cost burden will be addressed as part of the 48 CFR part 204 CMMC Acquisition rule. Summary: The following is the annual other than small entities total cost summary for Level 2 certification assessments and affirmations over a ten-year period: (Example calculation, Year 2: ($\$112,345$ assessment per entity $\times 673$ entities) + ($\$2,712$ annual affirmation per entity $\times 135$ entities) = $\$75,974,425$) Small Entities Nonrecurring or recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with Level 2 certification assessment since it is assumed the contractor or subcontractor has implemented the NIST SP 800-171 R2 security requirements. Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a Level 2 certification assessment and affirmation for a small entity is $\$101,752$. The three-year cost is $\$104,670$ (as summarized in 4.1.2, table 10), and includes the triennial assessment + affirmation plus two additional annual affirmations ($\$101,752 + \$1,459 + \$1,459$). Phase 1: Planning and preparing for the certification assessment: \$20,699 A director (MGMT5) for 54 hours ($\$190.52/\text{hr} \times 54\text{hrs} = \$10,288$) An external service provider (ESP) for 40 hours ($\$260.28/\text{hr} \times 40\text{hrs} =$ (printed page 83186) $\$10,411$) Phase 2: Conducting the certification assessment: \$45,509 A director (MGMT5) for 64 hours ($\$190.52/\text{hr} \times 64\text{hrs} = \$12,193$) An external service provider (ESP) for 128 hours ($\$260.28/\text{hr} \times 128\text{hrs} = \$33,316$) Phase 3: Reporting of certification assessment results: \$2,851 A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) An ESP for 8 hours ($\$260.28/\text{hr} \times 8\text{hrs} = \$2,082$) A staff IT specialist (IT4-SB) for 0.08 hours ($\$86.24/\text{hr} \times 0.08\text{hrs} = \7) Affirmations: cost to post initial affirmation \$1,459 C3PAO Costs:

(B) The investigation or proceeding involves a possible violation of criminal law where there is reason to believe that the subject of the investigation or proceeding is unaware of the pending investigation or proceeding. (C) The disclosure of the existence of the records could reasonably be expected to interfere with enforcement proceedings. (ii) Exclusion 2 . The DoD Components may treat records requested as not subject to the FOIA when a third party uses an informant's name or personal identifier to request informant records maintained by a criminal law enforcement organization within the DoD Component, and the informant's status as an informant has not been officially confirmed. (h) Exemption 8. Pursuant to 5 U.S.C. 552(b)(8) of Reference (b), records contained in or related to examination, operation, or condition reports prepared by, on behalf of, or for the use of any agency responsible for the regulation or supervision of financial institutions are exempt from disclosure. (i) Exemption 9 . Pursuant to 5 U.S.C. 552(b)(9) , records containing geological and geophysical information and data (including maps) concerning wells are exempt from disclosure. Subpart D-FOIA Request Processing § 286.17 General provisions. (a) Release of agency records. 5 U.S.C. 552(a) mandates release of agency records in response to a written request, unless: (1) The record is subject to one or more FOIA exemptions. (2) The record has not been described well enough to enable the DoD Component to locate it with a reasonable amount of effort by an employee familiar with the files. (3) The requester has failed to comply with procedural requirements, including failure to comply with a written agreement to pay any required fee incurred in processing previous requests. (b) Requests from private parties. (1) The provisions of the FOIA are reserved for members of the public as opposed to U.S. Federal agencies

seeking official information. Requests may be submitted in person, by mail, facsimile, or electronically. Commercial delivery is acceptable; however, due to security concerns, the DoD Components may refuse to accept commercial delivery of requests. (2) Individuals seeking DoD information should address their FOIA requests to one of the FOIA Requester Service Center addresses listed in Appendix B to this part. If a requester is not sure where to send a FOIA for DoD information, the request can be sent to the OSD/Joint Staff FOIA Requester Service Center. (3) The subject of a FOIA request may involve documents located at multiple Federal Government agencies. When this is the case, the DoD Components should try to determine whether the requester sent the request to the other relevant agencies. The requester should be contacted by the Component if the request does not mention any other agencies to which the request was sent.

The information collection requirements of the Defense Federal Acquisition Regulation Supplement (DFARS) part 245, Government Property, related clauses in DFARS part 252, and related forms in DFARS part 253, have been approved by the Office of Management and Budget (OMB) under OMB Control Number 0704-0246. No new information collection requirements are imposed by this final rule. List of Subjects in 48 CFR Parts 201, 245, and 252 Government procurement Ynette R. Shelkin, Editor, Defense Acquisition Regulations System. Therefore, 48 CFR parts 201, 245, and 252 are amended as follows: 1. The authority citation for 48 CFR parts 201, 245, and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1. PART 201-FEDERAL ACQUISITION REGULATIONS SYSTEM 2. Add section 201.670 to read as follows: 201.670 Appointment of property administrators and plant clearance officers. (a) The appropriate agency authority shall appoint or terminate (in writing) property administrators and plant clearance officers. (b) In appointing qualified property administrators and plant clearance officers, the appointing authority shall consider experience, training, education, business acumen, judgment, character, and ethics. PART 245-GOVERNMENT PROPERTY 3. Amend section 245.107 by adding paragraph (e) to read as follows: 245.107 Contract clauses. * * * * (d) Use the clause at 252.245-7004, Reporting, Reutilization, and Disposal, in solicitations and contracts that contain the clause at FAR 52.245-1, Government Property. 4. Add subpart 245.5, consisting of section 245.570, to read as follows: Subpart 245.5-Support Government Property Administration 245.570 Storage at the Government's expense. All storage contracts or agreements shall be separately priced and shall include all costs associated with the storage. 5. Revise subpart 245.6 to read as follows: Subpart 245.6-Reporting, Reutilization, and Disposal 245.602 Reutilization of Government property. 245.602-1 Inventory disposal schedules. 245.602-3 Screening. 245.602-70 Plant clearance procedures. 245.604 Disposal of surplus property. 245.604-3 Sale of surplus property. Subpart 245.6-Reporting, Reutilization, and Disposal 245.602 Reutilization of Government property. 245.602-1 Inventory disposal schedules. For termination inventory, plant clearance officers shall verify inventory schedules, either directly or through appropriate technical personnel, to determine the following: (a) Allocability. (1) Review contract requirements, delivery schedules, bills of material, and other pertinent documents to determine whether schedules include property that: (i) Is appropriate for use on the contract; or (ii) Exceeds the quantity required for completion of the contract, but could be diverted to other commercial work or Government use. (2) Review the contractor's: (i) Recent purchases of similar material; (ii) Plans for current and scheduled production; (iii) Stock record entries; and (iv) Bills of material for similar items. (b) Quantity.

(B) Exempted portions of this system also contain information considered relevant and necessary to make a determination as to qualifications, eligibility, or suitability for Federal employment and Federal contracts, and that was obtained by providing an express or implied promise to the source that his or her identity would not be revealed to the subject of the record. (20) System identifier and name. N12930-1, Human Resources Group Personnel Records. (i) Exemptions. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (B) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6), if the disclosure would compromise the objectivity or fairness of the test or examination process. (C) Portions of this system of records are exempt from the following subsections of the Privacy Act: (d), (e)(4)(G) and (H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) and (k)(6). (iii) Reasons. (A) Exempted portions of this system contain information considered relevant and necessary to make a determination as to

qualifications, eligibility, or suitability for Federal employment, and was obtained by providing express or implied promise to the source that his or her identity would not be revealed to the subject of the record. (B) Exempted portions of this system also contain test or examination material used solely to determine individual qualifications for appointment or promotion in the Federal Service, the disclosure of which would comprise the objectivity or fairness of the testing or examination process. (21) System identifier and name. N05813-4, Trial/Government Counsel Files. (i) Exemption. Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principle function any activity pertaining to the enforcement of criminal laws. Portions of this system of records that may be exempt pursuant to subsection 5 U.S.C. 552a(j)(2) are (c)(3), (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(5), (e)(4)(G), (H), and (I), (e)(8), (f), and (g). (ii) Exemption. Information specifically authorized to be classified under E.O. 12958, as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (iii) Exemption. Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2).

Computer technology Electronic information system Electronic transactions Employer benefit plan Group health plan Health Health care Health facilities Health insurance Health professions Health records Hospitals Investigations Medicaid Medical Research Medicare Penalties Preemption Privacy Public health Reporting and recordkeeping requirements Security 45 CFR Part 164 Administrative practice and procedure Computer technology Drug abuse Electronic information system Electronic transactions Employer benefit plan Group health plan Health Health care Health facilities Health insurance Health professions Health records Hospitals Medicaid Medical research Medicare Privacy Public health Reporting and recordkeeping requirements Security Proposed Rule For the reasons stated in the preamble, the Department of Health and Human Services proposes to amend 45 CFR subtitle A, subchapter C, parts 160 and 164 as set forth below: PART 160-GENERAL ADMINISTRATIVE REQUIREMENTS 1. The authority citation for part 160 continues to read as follows: Authority: 42 U.S.C. 1302(a); 42 U.S.C. 1320d-1320d-9; sec. 264, Pub. L. 104-191, 110 Stat. 2033-2034 (42 U.S.C. 1320d-2 (note)); 5 U.S.C. 552; secs. 13400-13424, Pub. L. 111-5, 123 Stat. 258-279; and sec. 1104 of Pub. L. 111-148, 124 Stat. 146-154. 2. Amend § 160.103 by revising the definition of "Electronic media" to read as follows: § 160.103 Definitions. * * * * * Electronic media means: (1) Electronic storage material on which data may be recorded, maintained, or processed. This includes, but is not limited to, hard drives, (printed page 1011) removable media, magnetic tape, optical disk, and any other form of digital memory or storage. (2) Transmission media used to exchange information already in electronic storage material. Transmission media includes, but is not limited to, the internet, extranet or intranet, leased lines, dial-up lines, private and public networks, and the physical movement of removable/transportable electronic storage material. * * * * * PART 164-SECURITY AND PRIVACY 1. The authority citation for part 164 continues to read as follows: Authority: 42 U.S.C. 1302(a); 42 U.S.C. 1320d-1320d-9; sec. 264, Pub. L. 104-191, 110 Stat. 2033-2034 (42 U.S.C. 1320d-2(note)); and secs. 13400-13424, Pub. L. 111-5, 123 Stat. 258-279. 2. Revise and republish subpart C to read as follows: Subpart C-Security Standards for the Protection of Electronic Protected Health Information 164.302 Applicability. 164.304 Definitions. 164.306 Security standards: General rules. 164.308 Administrative safeguards. 164.310 Physical safeguards. 164.312 Technical safeguards. 164.314 Organizational requirements. 164.316 Documentation requirements. 164.318 Transition provisions. 164.320 Severability. Appendix A to Subpart C of Part 164-Security Standards: Matrix Authority: 42 U.S.C. 1320d-2 and 1320d-4; 42 U.S.C. 17931. § 164.302 Applicability.

cyber, physical, and deception). To address APTs, NIST has published NIST SP 800-172 Feb2022. CMMC Level 3 certification assessment provides for government assessment of a contractor's implementation of a defined subset of NIST SP 800-172 Feb2021 Enhanced Security Requirements with DoD predefined parameters and specifications. (c) Scale and Depth Today, DoD prime contractors must include DFARS clause 252.204-7012 in subcontracts for which performance will involve covered defense information, but this does not provide the Department with sufficient insights with respect to the cybersecurity posture of all members of a multi-tier supply chain for any given program or technology development effort. The revised CMMC Program requires prime contractors to flow down CMMC requirements, as applicable, to subcontractors throughout their supply chain(s). Given the size of the Defense Industrial Base (DIB), the Department cannot scale its existing cybersecurity assessment workforce to conduct on-site assessments of approximately 220,000 DoD contractors and subcontractors every three years. The Department's existing assessment capability is best suited for conducting targeted

assessments for the relatively small subset of DoD contractors and subcontractors that support designated high-priority programs. CMMC addresses the Department's scaling challenges by utilizing a private-sector accreditation structure. The DoD-recognized Accreditation Body will authorize, accredit, and provide oversight of CMMC Third-Party Assessment Organizations (C3PAO) which in turn will conduct CMMC Level 2 certification assessments of actual and prospective DoD contractors and subcontractors. Organizations Seeking Certification (OSCs) will directly contract with an authorized or accredited C3PAO to undergo a Level 2 certification assessment to achieve a CMMC Status of Conditional and Final Level 2 (C3PAO). The cost of CMMC Level 2 activities is driven by multiple factors, including market forces that govern availability of C3PAOs and the size and complexity of the enterprise or enclave under assessment. The Government will perform Level 3 certification assessments. Government resource limitations may affect schedule availability. (printed page 83196) (d) Reduces Duplicate or Repetitive Assessments of Our Industry Partners CMMC assessment results and contractor affirmations of compliance will be posted in Supplier Performance Risk System (SPRS), DoD's authoritative source for supplier and product performance information. Posting CMMC assessment results in SPRS precludes the need to validate CMMC implementation on a contract-by-contract basis. This enables DoD to identify whether the CMMC assessment requirements have been met for relevant contractor information system(s), avoids duplicative assessments, and eliminates the need for program level assessments, all of which results in decreased costs to both DoD and industry. Significant Issues Raised by Public Comments

Written comments and recommendations on the proposed information collections should be sent to Ms. Jasmeet Seehra at the Office of Management and Budget, DoD Desk Officer, Room 10102, New Executive (printed page 89118) Office Building, Washington, DC 20503, with a copy to the Department of Defense, Office of the Assistant to the Secretary of Defense for Privacy, Civil Liberties, and Transparency, Regulatory Directorate, 4800 Mark Center Drive, Mailbox #24 Suite 08D09, Alexandria, VA 22350-1700. Comments can be received from 30 to 60 days after the date of this notice, but comments to OMB will be most useful if received by OMB within 30 days after the date of this notice. You may also submit comments, identified by docket number DoD-2023-OS-0063 and title through the Federal eRulemaking Portal at <https://www.regulations.gov> . Follow the instructions for submitting comments. Instructions: All submissions received must include the agency name, docket number and title for this Federal Register document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing on the internet at <https://www.regulations.gov> as they are received without change, including any personal identifiers or contact information. To request more information on these proposed information collections or to obtain a copy of the proposal and associated collection instruments, please write to Department of Defense, Office of the DoD Chief Information Officer, 4800 Mark Center Drive, Suite 11G14, Alexandria, VA 22350 or contact Ms. Diane Knight at 202-770-9100 or diane.l.knight10.civ@mail.mil . F. Executive Order 13132 , ·Federalism· Executive Order 13132 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct requirement costs on state and local governments, preempts state law, or otherwise has federalism implications. This proposed rule will not have a substantial effect on State and local governments. G. Executive Order 13175 , ·Consultation and Coordination With Indian Tribal Governments· Executive Order 13175 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct compliance costs on one or more Indian Tribes, preempts Tribal law, or effects the distribution of power and responsibilities between the federal government and Indian Tribes. This proposed rule will not have a substantial effect on Indian Tribal governments. List of Subjects in 32 CFR Part 170 CMMC CMMC Program CMMC Levels Cybersecurity Certification Federal Contract Information Controlled Unclassified Information Contracts Government procurement Incorporation by reference Accordingly, the Department of Defense proposes to add 32 CFR part 170 to read as follows: PART 170·CYBERSECURITY MATURITY MODEL CERTIFICATION (CMMC) PROGRAM Subpart A·General Information. 170.1 Purpose. 170.2

Amend section 232.502-4-70 by adding paragraph (c) to read as follows: 232.502-4-70 Additional clauses. * * * * * (c) Use the clause at 252.232-7018, Progress Payments·Multiple Lots, to authorize separate progress payment requests for multiple lots. PART 252·SOLICITATION PROVISIONS AND CONTRACT CLAUSES 4. Amend section 252.204-7006· a. By revising the section heading, clause heading, and clause date; and b. In the clause introductory text, removing ·payment· and adding ·payment using a cost voucher· in its place. The revisions read as follows: 252.204-7006 Billing Instructions·Cost Vouchers. * * * * * Billing Instructions·Cost Vouchers (May 2023) * * *

* * 5. Revise section 252.232-7002 to read as follows: 252.232-7002 Progress Payments for Foreign Military Sales Acquisitions. As prescribed in 232.502-4-70(a), use the following clause: Progress Payments for Foreign Military Sales Acquisitions (May 2023) If this contract includes foreign military sales (FMS) requirements, the Contractor shall: (a) Submit separate progress payment requests for the FMS and U.S. line items in the contract; (b) Submit a supporting schedule showing the amount of each request distributed to each country's requirements; (c) Identify in each progress payment request the contract requirements to which it applies (i.e., FMS or U.S.); (d) Calculate each request on the basis of the prices, costs (including costs to complete), subcontract financing, and progress payment liquidations of the contract requirements to which it applies; and (e) Distribute costs among the countries in a manner acceptable to the Administrative Contracting Officer. (End of clause) 6. Add section 252.232-7018 to read as follows: 252.232-7018 Progress Payments-Multiple Lots. As prescribed in 232.502-4-70(c), use the following clause: Progress Payments-Multiple Lots (May 2023) (a) Definitions. As used in this clause: Lot means one or more fixed-price deliverable line items or deliverable subline items representing a single, severable group where the sum of the costs for each group is segregated and a single progress payment rate is used. Multiple lots means more than one lot on a single contract where progress payment proration is performed on a lot-wide, versus contract-wide, basis. (b) When submitting progress payment requests under the billing instructions in Federal Acquisition Regulation (FAR) clause 52.232-16, Progress Payments, or Defense Federal Acquisition Regulation Supplement (DFARS) clause 252.232-7002, Progress (printed page 33834) Payments for Foreign Military Sales Acquisitions, of this contract, the Contractor shall: (1) Submit separate progress payment requests for each lot identified in the contract; (2) Identify the contract price for the lot as the sum of all fixed-priced line items identified to the lot, in accordance with FAR 32.501-3; (3) Identify the lot on each progress payment request to which the request applies;

(vii) Information for which foreign disclosure has been prohibited in whole or in part. (viii) Information provided to the USG in confidence by a third-party government. (ix) Classified information furnished by a third-party government. (l) Temporary eligibility for access to classified information. In accordance with SEAD 8 (available at: https://www.dni.gov/-/files/-/NCSC/-documents/-Regulations/-SEAD-8_-Temporary_-Eligibility_-U.pdf), the CSA may grant temporary (previously called interim) eligibility for access to classified information, as appropriate, to applicants for access to TOP SECRET, SECRET, and CONFIDENTIAL information. This eligibility may only be granted if there is no evidence of adverse information that calls into question an individual's eligibility for access to classified information. If results are favorable following completion of full investigative requirements, the CSA will update the temporary eligibility determination for access to classified information to be final. In any case, a temporary eligibility determination shall not exceed one year unless approved by the applicable CSA in the system of record. Non-U.S. citizens are not eligible for access to classified information on a temporary basis. (1) A temporary SECRET or CONFIDENTIAL eligibility determination is valid for access to classified information at the level of the eligibility granted. Access to RD, COMSEC information, and NATO information requires a final SECRET eligibility determination. (2) A temporary TOP SECRET eligibility determination is valid for access to TOP SECRET information. If an individual has a temporary TOP SECRET eligibility determination and has a final SECRET eligibility determination based on a previously completed investigation, the temporary TOP SECRET eligibility determination is valid for access to RD, NATO, and COMSEC information at the SECRET or CONFIDENTIAL level. (3) Access to SCI and SAP information based on a temporary eligibility determination is a determination made by the granting authority. (4) When a temporary eligibility determination has been made and derogatory information is subsequently developed, the CSA may withdraw the temporary eligibility pending completion of the processing that is a prerequisite to the final eligibility determination. (5) When a temporary eligibility determination is withdrawn for an individual who is required to be eligible for access to classified information in connection with the entity eligibility determination for access to classified information, the contractor must remove the individual from access to classified information and any KMP position requiring PCL eligibility or the temporary entity eligibility determination will also be withdrawn. (6) Withdrawal of a temporary eligibility determination is not a denial, termination, or revocation of eligibility under this rule and may not be appealed. (m) Consultants.

DoD does not expect this rule to have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601 , et seq. , because the rule relates to an administrative requirement for TIN validation, which is performed by the

Government. Contractors need only provide consent for TIN validation as part of the CCR registration process. Therefore, DoD has not performed an initial regulatory flexibility analysis. DoD invites comments from small businesses and other interested parties. DoD also will consider comments from small entities concerning the affected DFARS subpart in accordance with 5 U.S.C. 610. Such comments should be submitted separately and should cite DFARS Case 2006-D037. C. Paperwork Reduction Act The Paperwork Reduction Act does not apply, because the rule does not impose any information collection requirements that require the approval of the Office of Management and Budget under 44 U.S.C. 3501, et seq. List of Subjects in 48 CFR Part 252 Government procurement Michele P. Peterson, Editor, Defense Acquisition Regulations System. Therefore, DoD proposes to amend 48 CFR Part 252 as follows: PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 1. The authority citation for 48 CFR Part 252 continues to read as follows: Authority: 41 U.S.C. 421 and 48 CFR Chapter 1. 2. Section 252.204-7004 is amended as follows: a. By revising the section heading, clause title, and clause date; and b. In paragraph (a), by revising the definition of Registered in the CCR database to read as follows: 252.204-7004 Alternate A, Central Contractor Registration. Alternate A, Central Contractor Registration (XXX 2007) * * * * (a) * * * Registered in the CCR database means that: (1) The Contractor has entered all mandatory information, including the DUNS number or the DUNS+4 number, into the CCR database; (2) The Contractor's CAGE code is in the CCR database; and (3) The Government has validated all mandatory data fields, to include validation of the Taxpayer Identification Number (TIN) with the Internal Revenue Service, and has marked the records Active. The Contractor will be required to provide consent for TIN validation to the Government as part of the CCR registration process. [FR Doc. E7-736 Filed 1-19-07; 8:45 am] BILLING CODE 5001-08-P

(3) In coordination with the appropriate requiring activity (or activities), ensure the head of the contracting activity responsible for each covered contract takes appropriate steps to assign sufficient oversight personnel to the contract to verify that the contractor responsible for performing private security functions complies with the requirements of this part. This includes ensuring that the contracting officer coordinates with the requiring activity to nominate and appoint a qualified contracting officer's representative (COR) or other multiple or alternate CORs, in accordance with DoD Instruction 5000.72, DoD Standard for Contracting Officer's Representative (COR) Certification (available at <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodi/500072p.pdf>). 7. Amend § 159.6 by: a. Revising paragraph (a) introductory text. b. In paragraph (a)(1)(i), removing Contractor Personnel Authorized to Accompany the U.S. Armed Forces... and adding a period in its place. c. In paragraph (a)(1)(iii) introductory text: i. Removing geographic Combatant Commander and adding in its place CCDR of the geographic AOR wherever it appears. ii. Removing of this part. d. In paragraph (a)(1)(iii)(C): i. Removing Guidance for Determining Workforce Mix... and adding in its place Policy and Procedures for Determining Workforce Mix... ii. Redesignating footnote 12 as footnote 1. e. In paragraph (a)(1)(iii)(F)(1), redesignating footnote 13 as footnote 2. f. In paragraph (a)(1)(iv), adding PSC personnel, weapons, before armored vehicles. g. In paragraph (a)(1)(v)(F), removing TASER guns and adding in its place disruption devices. h. In paragraph (a)(1)(viii), removing commander of a combatant command may request and adding in its place CCDR may, through the contracting officer, request. i. In paragraph (a)(1)(x), removing paragraph (a)(2)(ii) and adding in its place paragraph (a)(2)(iii). j. In paragraph (a)(2)(i), removing Contractor Personnel Authorized to Accompany the U.S. Armed Forces... and adding a period in its place. k. Redesignating paragraphs (a)(2)(ii) through (iv) as paragraphs (a)(2)(iii) through (v) and adding new paragraph (a)(2)(ii). l. Further redesignating newly redesignated paragraph (a)(2)(v) as paragraph (a)(2)(vi) and adding new paragraph (a)(2)(v). m. In newly redesignated paragraph (a)(2)(vi), removing Chief of Mission and adding in its place COM. n. Removing paragraph (b) and redesignating paragraphs (c) and (d) as paragraphs (b) and (c). o. In newly redesignated paragraph (b): i. Revising the paragraph heading. ii. Removing Chief of Mission and combatant command and adding in their places COM and CCDR, respectively. p. In newly redesignated paragraph (c): i. Revising the paragraph heading. ii. Removing Chief of Mission and geographic Combatant Commander/sub unified commander and adding in their places COM and CCDR with geographic AOR/sub unified commander, respectively.

As proposed, Level 1 contractors would annually attest their compliance with the requirements. While at Level 2, there would be attestations with C3PAO certifications every three years. Stakeholders raised questions about the practical steps the DoD will take in enforcement actions for breaches.

Further, stakeholders raised concerns regarding the availability of remediating steps in the instance of failure to meet a CMMC requirement. Advocacy recommends the agency create guidance documents for small business contractors to better understand the legal effects of the CMMC. · DoD Response: Regarding enforcement, as the CMMC is slated for implementation as a precondition for contract award consideration, non-compliance with CMMC requirements will result in disqualification from contract award; or post-award, could result in standard contractual and other remedies for failure to timely and satisfactorily address outstanding POA&Ms to fully implement CMMC requirements and meet contractual obligations. · SBA Comment 5: Advocacy highlights the need for DoD to create rules that encourage and improve small business participation in contracting programs. Advocacy reiterates the importance of small businesses in Federal contracting. [Excerpt from footnote 21: ·Small businesses make up 99.9 percent of all U.S. businesses as well as 73 percent of companies in the defense industrial base, and last year small businesses were awarded over 25 percent of all DoD prime contracts. As the economic engine of our nation, small businesses create jobs, generate innovation, and are essential, daily contributors to national security and the defense mission.] Creating accessible, commercially viable, and secure cyber systems is critical for the future of national security. Small businesses wish to continue to be a powerful driver of national defense contracting. Advocacy heard small business stakeholders from across the country express their strong commitment to protecting our country from cyber-attacks and recognize the critical need for CMMC and other cybersecurity measures. ·Small businesses urge DoD to create flexibilities such as using Plan of Action and Milestones (POA&Ms) when this rule goes into effect initially, allowing small businesses to ramp up to full compliance with their respective CMMC level. · DoD Response: Department acknowledges the concerns voiced by the SBA regarding the participation of small businesses in contracting programs and the importance of fostering their involvement in Federal contracting, particularly within the defense industrial base. Recognizing the significant role small businesses play in national security and defense missions, the Department is committed to diligently addressing these concerns.

The reduction in benefits from excluding all foreign persons except those who transport food in the United States is considerable because the large number of excluded entities increases the likelihood of hampering traceback investigations. Moreover, the risk of contamination (unintentional) is generally higher for many products earlier in the supply chain. In addition, enforcement costs for foreign persons would likely be prohibitively high-decreasing the likelihood of obtaining records required for a traceback even if these persons were covered. When compared to the eight other individual options considered for the final rule, the large number of excluded foreign persons ranks third highest of the reductions in benefits relative to the baseline considered. This reduction in benefits, however, is mitigated in one respect: The risk of not being able to complete traceback investigations due to this exclusion is considered low because most of these foreign entities occupy positions early in the supply chain. The reduction in benefits from relaxing the recordkeeping requirements for persons who manufacture, process, pack, transport, distribute, import, receive, or hold food contact substances other than the finished container that directly contacts the food, and who manufacture or process the finished container that directly contacts the food, as estimated by the number of applicable facilities, is small. Although relaxing requirements for these persons may expose a ·soft target· for intentional contamination, the probability of foodborne illness from unintentionally contaminated food contact substance and finished container material is low. Furthermore, the likelihood of needing records from food contact substance and finished container facilities during traceback investigations is also low. When compared to the other issues considered for the final rule, relaxing the requirements for these persons ranks only seventh in the reductions in benefits relative to the baseline. The reduction in benefits from relaxing the requirement to access records within 24 hours from 4- and 8-hour requirement would be substantial. We estimate that relaxing the records access requirement would increase the amount of time for any preventive action to be taken during a traceback investigation by about 5 days relative to the baseline, if all persons subject to an access request took the full 24 hours to respond. The loss of time relative to the baseline would limit the preventive benefits for 15 percent to 18 percent of outbreaks. Relaxing the record access requirement from 4 and 8 hours, to within 24 hours ranks second in reductions in benefits relative to the baseline.

One comment notes that the proposed rule includes an exemption for restaurants, which are defined as facilities that sell food directly to consumers for immediate consumption. The comment asserts that many convenience stores make such sales of prepared foods, but convenience stores are included in the proposed rule's definitions as an example of retail facilities. In the comment's view,

convenience stores that sell food for immediate consumption should be exempt from the proposed rule. There is no reason why convenience stores that sell prepared foods should have greater regulatory burdens than any other type of entity that sells prepared foods. The comment further states that the restaurant exemption as currently proposed leads to results that are difficult to justify. The comment asks why, for example, should a convenience store that sells lunchmeat be required to comply with a costly system of recordkeeping, while a delicatessen that sells precisely the same product to the same consumer is exempt? The comment states that the only sensible answer to these unjustifiable inconsistencies is to exempt retailers that sell food to consumers for immediate consumption from the requirements of the regulation. (Response) FDA agrees with these comments. Section 306 of the Bioterrorism Act exempts restaurants from recordkeeping requirements. There is no similar exemption in section 306 for retail facilities. In the proposed rule, FDA exercised the agency's discretion and proposed excluding retail facilities from the requirement to establish and maintain records of the immediate subsequent recipients of food when the food is sold directly to consumers (68 FR 25188 at 25192). As explained therein, the Bioterrorism Act expressly states that the Secretary may require the establishment and maintenance of records by persons who distribute food, and therefore retail facilities could be subject to all of the provisions in subpart J of this final rule if FDA thought it was necessary to address credible threats of serious adverse health consequences or death to humans or animals.

The Department examined two different data points: the annual number of individuals affected by health care breaches, and the annual number of large breaches. Additionally, the Department considered a high and a low baseline based on the number of breaches and affected individuals per year. The Department calculated the high baseline as the average of the three highest values in the 6 years of available data (2018 to 2023, shown in table 8), and the low baseline as the average of the three lowest values. Table 8-Data on Breaches of e PHI Breach years Affected individuals for large breaches a Cost b per record 983 2018 12,493,549 \$488 2019 38,732,966 504 2020 37,641,403 476 2021 37,182,558 502 2022 41,747,613 477 2023 113,173,613 463 Number of large breaches (500+ individuals) Cost per breach 2018 302 12,012,809 2019 408 7,582,508 2020 656 8,273,537 2021 609 10,241,897 2022 626 10,468,138 2023 725 10,930,000 a The numbers of affected individuals and numbers of large breaches are contained in the Reports to Congress on Breaches of Unsecured Protected Health Information for years 2018-2022, <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/reports-congress/index.html> . Data for 2023 is contained in OCR's breach portal, "Breach Portal: Notice to the Secretary of HHS Breach of Unsecured Protected Health Information," Office for Civil Rights, U.S. Department of Health and Human Services, https://ocrportal.hhs.gov/ocr/breach/breach_report.jsf . b The cost per record and cost per breach are based on estimates for health care breaches from the annual IBM Security and Ponemon Institute Costs of a Data Breach Reports for years 2018-2023. See "Cost of a Data Breach Report 2023," IBM Security, p. 10, 13 (July 24, 2023), available at <https://www.ibm.com/reports/data-breach> . Because only general breach costs were available for the 2020-2023 period, the Department adjusted those by multiplying them by the average of the ratios of health care-specific to overall breach costs for the years for which both data points were available (2018, \$408/\$148 and 2019, \$429/\$150). All dollar values were converted to 2023 dollars using the seasonally adjusted GDP Implicit Price Deflator, <https://fred.stlouisfed.org/series/GDPDEF/> . The high baseline used 669 breaches and a total of 71 million individuals affected, and the low baseline used 440 breaches and 29 million individuals affected. [984] The high baseline represents years with higher incidence of breaches, whereas the low baseline represents years with lower incidence. For each data point, the Department calculated the number of breaches or affected individuals by which the affected universe would have to decrease for the proposed rule to fully offset the annualized costs of regulated entities. [985] Table 9 and the discussion that follows analyses the costs and cost savings based on the number of individuals affected by breaches in a year and the cost per individual's ePHI or medical record. (printed page 1004)

§ 170.15 CMMC Level 1 self-assessment and affirmation requirements. (a) Level 1 self-assessment. To comply with CMMC Level 1 self-assessment requirements, the OSA must meet the requirements detailed in paragraphs (a)(1) and (2) of this section. An OSA conducts a Level 1 self-assessment as detailed in paragraph (c) of this section to achieve a CMMC Status of Final Level 1 (Self). (1) Level 1 self-assessment requirements. The OSA must complete and achieve a MET result for all security requirements specified in § 170.14(c)(2) to achieve the CMMC Status of Final Level 1 (Self). No POA&Ms are permitted for CMMC Level 1. The OSA must conduct a self-assessment in

accordance with the procedures set forth in § 170.15(c)(1) and submit assessment results in SPRS. To maintain compliance with the requirements for the CMMC Status of Final Level 1 (Self), the OSA must conduct a Level 1 self-assessment on an annual basis and submit the results in SPRS, or its successor capability. (i) Inputs to SPRS. The Level 1 self-assessment results in the Supplier Performance Risk System (SPRS) shall include, at minimum, the following items: (A) CMMC Level. (B) CMMC Status Date. (C) CMMC Assessment Scope. (D) All industry CAGE code(s) associated with the information system(s) addressed by the CMMC Assessment Scope. (E) Compliance result. (ii) [Reserved] (2) Affirmation. Affirmation of the Level 1 (Self) CMMC Status is required for all Level 1 self-assessments. Affirmation procedures are set forth in § 170.22 . (b) Contract eligibility. Prior to award of any contract or subcontract with a requirement for the CMMC Status of Level 1 (Self), OSAs must both achieve a CMMC Status of Level 1 (Self) and have submitted an affirmation of compliance into SPRS for all information systems within the CMMC Assessment Scope. (c) Procedures · (1) Level 1 self-assessment. The OSA must conduct a Level 1 self-assessment scored in accordance with the CMMC Scoring Methodology described in § 170.24 . The Level 1 self-assessment must be performed in accordance with the CMMC Level 1 scope requirements set forth in § 170.19(a) and (b) and the following: (i) The Level 1 self-assessment must be performed using the objectives defined in NIST SP 800-171A Jun2018 (incorporated by reference, see § 170.2) for the security requirement that maps to the CMMC Level 1 security requirement as specified in table 1 to paragraph (c)(1)(ii) of this section. In any case where an objective addresses CUI, FCI should be substituted for CUI in the objective. (ii) Mapping table for CMMC Level 1 security requirements to the NIST SP 800-171A Jun2018 objectives. Table 2 to § 170.15 (c)(1)(ii) ·CMMC Level 1 Security Requirements Mapped to NIST SP 800-171A Jun2018 CMMC Level 1 security requirements as set forth in § 170.14(c)(2) NIST SP 800-171A Jun2018 AC.L1-b.1.i 3.1.1 AC.L1-b.1.ii 3.1.2 AC.L1-b.1.iii 3.1.20 AC.L1-b.1.iv 3.1.22 IA.L1-b.1.v 3.5.1 IA.L1-b.1.vi 3.5.2 MP.L1-b.1.vii 3.8.3 PE.L1-b.1.viii 3.10.1 First phrase of PE.L1-b.1.ix (FAR b.1.ix *) 3.10.3 Second phrase of PE.L1-b.1.ix (FAR b.1.ix *) 3.10.4 Third phrase of PE.L1-b.1.ix (FAR b.1.ix *) 3.10.5 SC.L1-b.1.x 3.13.1 SC.L1-b.1.xi 3.13.5 SI.L1-b.1.xii 3.14.1 SI.L1-b.1.xiii 3.14.2 SI.L1-b.1.xiv 3.14.4 SI.L1-b.1.xv 3.14.5 * Three of the 48 CFR 52.204-21 requirements were broken apart by ·phrase· when NIST SP 800-171 R2 was developed. (iii) Additional guidance can be found in the guidance document listed in paragraph (b) of appendix A to this part. (2) Artifact retention. The artifacts used as evidence for the assessment must be retained by the OSA for six (6) years from the CMMC Status Date.

As described in § 170.22(a)(2)(ii), the CMMC affirmation shall include a statement to the effect that the OSA has implemented and will maintain implementation ·within the relevant assessment scope·, which adequately addresses the commenters suggestion. No change to the rule text was therefore required. Annual affirmations ensure OSAs conduct periodic checks and verify to the Department that changes to their networks have not taken them out of compliance during the certification period. The annual affirmation requirement enables DoD to permit 3 years between CMMC Level 2 or 3 assessments, rather than requiring annual assessments. The DoD does not agree with the comment that following the procedures in § 170.22 creates an additional burden. The DoD does not concur with removing the terms ·continuing· or ·continuous· as it relates to an OSA's affirmation. Continuing compliance means that the contractor system in question remains in compliance and that the OSA intends to maintain compliance over time, not that the OSA cannot have an operational plan of action. Any changes to the information system beyond use of operational plans of action require a new assessment and a new affirmation. Operational plans of action as described in CA.L2-3.12.2 are part of normal (printed page 83146) maintenance of a system and do not require a separate out-of-cycle affirmation. The DoD declines to address specific cases when affirmations are not required. DoD's use of the term OSA within the affirmations section is deliberate and conveys that each organization is responsible for affirmations pertaining to their own assessments. An Affirming Official definition was added to the rule and provides that clarification. The rule delineates which requirements may be addressed with a POA&M for up to 180 days to achieve Final CMMC Status. As stated in § 170.22, an Affirming Official attests the organization is satisfying and will maintain its specified cybersecurity requirements. An OSA may complete a self-assessment and submit a new affirmation at any time. POA&Ms associated with conditional assessments are closed-out by C3PAOs for Level 2 final certification assessments and by DCMA DIBCAC for Level 3 final certification assessments. OSAs must affirm results in SPRS for all assessments. If an OSA makes significant changes within the CMMC Assessment Scope, a new assessment and affirmation are required. The rule does not preclude OSAs from contacting a C3PAO for a review prior to an annual affirmation, however this is not required. No supporting evidence is required for an annual affirmation. Annual representations and certifications submitted in the System for Award Management (SAM) serve a

different purpose from the CMMC affirmation requirement completed in SPRS. Furthermore, given the sensitivity of an OSA's cyber security status, the DoD has elected not to use SAM, a public website.

From the NIST SP 800-172 Rev 3 Final Public Draft: DISCUSSION Integrated analysis of audit records requires that the analysis of information NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 generated by scanning, monitoring, or other data collection activities is integrated 894

assembly, testing, acceptance, maintenance, system and network administration, shipping and receiving, packaging and labeling, delivery, inventory management, finance, disposal, and waste management. | Process | Risk Executive Function | CIO | SISO | Contracting | Legal | Mission/Business Owner |

-----|-----|-----|-----|-----|-----|-----|-----| Plan
Procurement | Oversee | Oversee | Oversee | Lead | Approve | Lead | | Define/Develop Requirements |
Oversee | Oversee | Oversee | Advise | Advise | Lead | | Identify Potential Suppliers and/or Perform
Market Analysis | Oversee | Oversee | Oversee | Advise | Advise | Lead | | Complete Procurement |
Oversee | Oversee | Approve | Lead | Approve | Lead | | Operations and Maintenance | Oversee |
Oversee | Oversee | Advise | Advise | Lead |

(u) The Commander, U.S. Army Criminal Investigation Command, is authorized to act on requests for criminal investigative records of USACIDC headquarters, and its subordinate activities, and military police reports. This includes criminal investigation records, investigation-in-progress records, and all military police records and reports that result in criminal investigation reports. This authority has been delegated to the Director, U.S. Army Crime Records Center. (v) The Commander, U.S. Army Human Resources Command, is authorized to act on requests for military personnel files relating to active duty personnel including, but not limited to military personnel matters, military education records including records related to the removal or suspension from a military school or class; personnel locator, physical disability determinations, and other military personnel administration records; records relating to military casualty and memorialization activities; heraldic activities, voting, records relating to identification cards, naturalization and citizenship, commercial solicitation, Military Postal Service Agency and Army postal and unofficial mail service. The Commander, U.S. Army Human Resources Command, is also authorized to act on requests concerning all personnel and medical records of retired, separated, discharged, deceased, and reserve component military personnel, unless such records clearly fall within another Denial Authority's authority. (w) The Commander, U.S. Army Resources Command-St. Louis has been delegated authority to act on behalf of the U.S. Army Human Resources Commander for requests concerning all personnel and medical records of retired, separated, discharged, deceased, and reserve component military personnel, unless such records clearly fall within another Denial Authority's authority. The authority does not include records relating to USAR plans, policies, and operations; changes in the organizational status of USAR units, mobilization and demobilization policies; active duty tours, and the individual mobilization augmentation program. (x) The Assistant Chief of Staff for Installation Management is authorized to act on requests for records relating to planning, programming, execution and operation of Army installations. This includes base realignment and closure activities, environmental activities other than litigation, facilities and housing activities, and installation management support activities. (y) The Commander, U.S. Army Intelligence and Security Command, is authorized to act on requests for intelligence and security records, foreign scientific and technological records, intelligence training, intelligence threat assessments, and foreign liaison information, mapping and geodesy information, ground surveillance records, intelligence threat assessment, and missile intelligence data relating to tactical land warfare systems.

Version 2.13 | September 2024 DoD-CIO-00003 (ZRIN 0790-ZA19) CMMC Assessment Guide Level 2
24-T-0461 CMMC Assessment Guide · Level 2 | Version 2.13 ii NOTICES The contents of this document
do not have the force and effect of law and are not meant to bind the public in any way. This
document is intended only to provide clarity to the public regarding existing requirements under
the law or departmental policies. DISTRIBUTION STATEMENT A. Approved for public release.
Distribution is unlimited.

creation of FCI or CUI as part of the contract effort. Such waivers will be requested and approved by DoD in accordance with internal policies, procedures, and approval requirements. The Department

ultimately adopted alternatives 3 and 4. The drawback of alternative 1 (at time of proposal or offer submission) is the increased risk for contractors since they may not have sufficient time to achieve the required CMMC level after the release of the solicitation. The drawback of alternative 2 (after contract award) is the increased risk to the Department with respect to the costs, program schedule, and uncertainty in the event the contractor is unable to achieve the required CMMC level in a reasonable amount of time given their current cybersecurity posture. This potential delay would apply to the entire supply chain and prevent the appropriate flow of CUI and FCI. The Department seeks public comment on the requirement to achieve a specified CMMC level by the time of contract award. Benefits The Department of Defense expects this proposed rule to protect DoD and industry from the loss of FCI and CUI, including intellectual property. The theft of intellectual property and sensitive unclassified information due to malicious cyber activity threatens U.S. economic security and national security. In 2010, the Commander of the U.S. Cyber Command and Director of the National Security Agency estimated the value of U.S. intellectual property to be \$5 trillion and that \$300 billion is stolen over networks annually [46] . The 2013 Intellectual Property Commission Report provided concurrence and noted that the ongoing theft represents the greatest transfer of wealth in history. The report also highlighted the challenges of generating an exact figure because Government and private studies tend to understate the impacts due to inadequate data or scope, which is evidenced in subsequent analyses. [47] The responsibility of federal agencies to protect FCI or CUI does not change when such information is shared with defense contractors. A comparable level of protection is needed when FCI or CUI is processed, stored, or transmitted on contractor information systems. [48] The protection of FCI, CUI, and intellectual property on defense contractor systems can directly impact the ability of the federal government to successfully conduct its essential missions and functions. [49]

SC.L2-3.13.9 · Connections Termination CMMC Assessment Guide · Level 2 | Version 2.13 230
 FURTHER DISCUSSION Prevent malicious actors from taking advantage of an open network session or an unattended computer at the end of the connection. Balance user work patterns and needs against security to determine the length of inactivity that will force a termination. This requirement, SC.L2-3.13.9, specifies network connections be terminated under certain conditions, which complements AC.L2 -3.1.18 that specifies control of mobile device connections. Example You are an administrator of a server that provides remote access. Your company's policies state that network connections must be terminated after being idle for 60 minutes [a]. You edit the server configuration file and set the timeout to 60 minutes and restart the remote access software [c]. You test the software and verify that the connection is terminated appropriately. Potential Assessment Considerations · Are the network connections requiring management and time-out for inactivity documented [a]? · Are the network connections requiring management and time-out for inactivity configured and implemented [c]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.13.9

Commentary to 2 ; A number of papers included in this report propose several security levels. Michael Baum proposes three numbered levels and defines each level with "baseline" characteristics. Peter Weiss proposes four levels, including a non-sensitive level. Jim Orr identifies types of data transmissions in health care applications for each of three risk levels: low, medium, and high. Irvin Chmielewski states that a "balance of high and low tech solutions to achieve EDI security has made the process workable in the real world where large numbers of trading partners are involved." All participants recognized that a "one size fits all" techniques is generally consistent with that contained in the American Bar Association's Model Payments Agreement and Commentary ("Model Agreement") . 32 Jurimetrics 601 (Summer, 1992) . Similarly, Michael Baum's Security Baseline -Level 1 includes only noncryptographic techniques. | L Introduction | |-----| | n. Security and Reliability | | a. Treatment in the Law | | b. Reasonable Security Procedures | | c Mapping Security Attributes to Legal Standards | | Table 1 - Comparison of Signed Writings and Electronic Information^.. | | Table 2 - Fallibilities of Paper-based Signatures | | d. Non-repudiation | | e. Trusted Entities and Time Stamping | | Hl. Risk Analysis and Risk-Based Approaches | | a. Risk Analysis | | b.

3.2.6. Verifier-CSP or IdP Communications Throughout this document, [FIPS140] requirements are satisfied by security technologies, products, and services that utilize implementations of cryptography validated by the Cryptography Module Validation Program [CMVP]. FIPS 140 requirements at a given AAL are often different for authenticators and verifiers, with more stringent requirements generally applying to verifiers. This is in recognition of the practical

limitations on the certification of authenticators as well as the broader scope that is often associated with a security breach at a verifier. 2.1.2. Authenticator and Verifier Requirements Authenticators used at AAL1 SHALL use approved cryptography. In other words, they must use approved algorithms, but the implementation need not be validated under [FIPS140].

(iii) Coordinating with the local Staff Judge Advocate to determine whether a more formal investigation such as a commander's inquiry or an AR 15-6 investigation is appropriate; and (iv) Ensuring the decision at the local level from either the Privacy Act Officer or other individual who directed a more formal investigation is provided to the complainant in writing. (2) The decision at the local level may be appealed to the next higher command level Privacy Act Officer. (3) A legal review from the next higher command level Privacy Act Officer's servicing Staff Judge Advocate is required prior to action on the appeal. §505.13 Computer Matching Agreement Program. (a) General provisions. (1) Pursuant to the Privacy Act and this part, DA records may be subject to computer matching, i.e., the computer comparison of automated systems of records. (2) There are two specific kinds of Matching Programs covered by the Privacy Act: (i) Matches using records from Federal personnel or payroll systems of records; and (ii) Matches involving Federal benefit programs to accomplish one or more of the following purposes: (A) To determine eligibility for a Federal benefit; (B) To comply with benefit program requirements; and (C) To effect recovery of improper payments or delinquent debts from current or former beneficiaries. (3) The comparison of records must be computerized. Manual comparisons are not covered. (4) Any activity that expects to participate in a Computer Matching Program must contact the DA FOIA/P Office immediately. (5) In all cases, Computer Matching Agreements are processed by the Defense Privacy Office and approved by the Defense Data Integrity Board. Agreements will be conducted in accordance with the requirements of 5 U.S.C. 552a, and OMB Circular A-130. (b) Other matching. Several types of computer matching are exempt from the restrictions of the Act such as matches used for statistics, pilot programs, law enforcement, tax administration, routine administration, background checks, and foreign counterintelligence. The DA FOIA/P Office should be consulted if there is a question as to whether the Act governs a specific type of computer matching. §505.14 Recordkeeping requirements under the Privacy Act. (a) AR 25-400-2, The Army Records Information Management System (ARIMS). To maintain privacy records are required by the Army Records Information Management System (ARIMS) to provide adequate and proper documentation of the conduct of Army business so that the rights and interests of individuals and the Federal Government are protected. (b) A full description of the records prescribed by this part and their disposition/retention requirements are found on the ARIMS Web site at <https://www.arims.army.mil>. Appendix A to Part 505-References (a) The Privacy Act of 1974 (5 U.S.C. 552a, as amended). (b) OMB Circular No. A-130, Management of Federal Information Resources. (printed page 24508) (c) AR 25-55, The Department of the Army Freedom of Information Program.

During the course of a FOIA/Privacy Act and/or MDR action, exempt materials from other system of records may become part of the case records in this system of records. To the extent that copies of exempt records from those other systems of records are entered into these case records, NSA/CSS hereby claims the same exemptions for the records as claimed in the original primary system of records of which they are a part. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a. §310.28 Office of the Inspector General (OIG) exemptions. (a) Exemption for classified records. Any record in a system of records maintained by the Office of the Inspector General which falls within the provisions of 5 U.S.C. 552a(k)(1) may be exempt from the following subsections of 5 U.S.C. 552a: (c)(3), (d), (e)(1), (e)(4)(G) through (I) and (f) to the extent that a record system contains any record properly classified under Executive Order 12958 and that the record is required to be kept classified in the interest of national defense or foreign policy. This specific exemption rule, claimed by the Inspector General under authority of 5 U.S.C. 552a(k)(1), is applicable to all systems of records maintained, including those individually designated for an exemption herein as well as those not otherwise specifically designated for an exemption, which may contain isolated items of properly classified information. (b) The Inspector General of the Department of Defense claims an exemption for the following record systems under the provisions of 5 U.S.C. 552a(j) and (k)(1)-(k)(7) from certain indicated subsections of the Privacy Act of 1974. The exemptions may be invoked and exercised on a case-by-case basis by the Deputy Inspector General for Investigations or the Director, Communications and Congressional Liaison Office, and the Chief, Freedom of Information/Privacy Act Office, which serve as the Systems Program Managers. Exemptions will be exercised only when necessary for a specific, significant and legitimate reason connected

with the purpose of the records system. (c) No personal records releasable under the provisions of The Freedom of Information Act (5 U.S.C. 552) will be withheld from the subject individual based on these exemptions. (1) System identifier and name. CIG-04, Case Control System. (i) Exemption. Any portion of this system which falls within the provisions of 5 U.S.C. 552a(j)(2) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3), (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (H), (I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons.

(d) Limit, notwithstanding any other provision of law, in whole or in part, the disclosure of information relating to the basis for carrying out any of the actions authorized by paragraphs (a) through (c) of this section, and if such disclosures are so limited- (1) No action undertaken by the individual authorized under such authority shall be subject to review in a bid protest before the Government Accountability Office or in any Federal court; and (2) The authorized individual shall- (i) Notify appropriate parties of a covered procurement action and the basis for such action only to the extent necessary to effectuate the covered procurement action; (ii) Notify other Department of Defense components or other Federal agencies responsible for procurements that may be subject to the same or similar supply chain risk, in a manner and to the extent consistent with the requirements of national security; and (iii) Ensure the confidentiality of any such notifications.

239.7306 Solicitation provision and contract clause. (a) Insert the provision at 252.239-7017, Notice of Supply Chain Risk, in all solicitations, including solicitations using FAR part 12 procedures for the acquisition of commercial items, that involve the development or delivery of any information technology whether acquired as a service or as a supply. (b) Insert the clause at 252.239-7018, Supply Chain Risk, in all solicitations and contracts, including solicitations and contracts using FAR part 12 procedures for the acquisition of commercial items, that involve the development or delivery of any information technology whether acquired as a service or as a supply.

PART 244-SUBCONTRACTING POLICIES AND PROCEDURES 9. Add new sections 244.201 and 244.201-1 to subpart 244.2 to read as follows: 244.201 Consent and advance notification requirements.

244.201-1 Consent requirements. In all solicitations and contracts involving the development or delivery of any information technology, whether acquired as a service or as a supply, consider the need for a consent to subcontract requirement regarding supply chain risk (see subpart 239.73).

PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 10. Add section 252.239-7017 to read as follows: 252.239-7017 Notice of supply chain risk. As prescribed in 239.7306(a), use the following provision: NOTICE OF SUPPLY CHAIN RISK (NOV 2013) (a) Definition. Supply chain risk, as used in this provision, means the risk that an adversary may sabotage, maliciously introduce unwanted function, or otherwise subvert the design, integrity, manufacturing, production, distribution, installation, operation, or maintenance of a national security system (as that term is defined at 44 U.S.C. 3542(b)) so as to surveil, deny, disrupt, or otherwise degrade the function, use, or operation of such system. (b) In order to manage supply chain risk, the Government may use the authorities provided by section 806 of Public Law 111-383

to limit disclosure of information, no action undertaken by the Government under such authority shall be subject to review in a bid protest before the Government Accountability Office or in any Federal court. (e) The Contractor shall include the substance of this clause, including this paragraph (e), in all subcontracts involving the development or delivery of any information technology, whether acquired as a service or as a supply. (End of clause) [FR Doc. 2013-27311 Filed 11-15-13; 8:45 am] BILLING CODE 5001-06-P

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary [DoD-2007-OS-0086; 0790-AI24] 32 CFR Part 286 AGENCY: Department of Defense. ACTION: Proposed rule. SUMMARY: The Department of Defense is proposing to update current policies and procedures to reflect the DoD FOIA Program as prescribed by Executive Order 13392 . The proposed changes will ensure appropriate agency disclosure of information, and offer consistency with the goals of section 552 of title 5, United States Code. DATES: Comments must be received by February 19, 2008. ADDRESSES: You may submit comments, identified by docket number and/or RIN number and title, by any of the following methods: Federal Rulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting

comments. Mail: Federal Docket Management System Office, 1160 Defense Pentagon, Washington, DC 20301-1160. Instructions: All submissions received must include the agency name and docket number or Regulatory Information Number (RIN) for this Federal Register document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing on the Internet at <http://regulations.gov> as they are received without change, including any personal identifiers or contact information. FOR FURTHER INFORMATION CONTACT: James Hogan (703) 696-4495. SUPPLEMENTARY INFORMATION: Executive Order 13132, 'Federalism'. It has been certified that 32 CFR part 286 does not have federalism implications, as set forth in Executive Order 13132. This rule does not have substantial direct effects on: (1) The States; (2) The relationship between the National Government and the States; or (3) The distribution of power and responsibilities among the various levels of Government. Executive Order 12866, 'Regulatory Planning and Review'. It has been certified that 32 CFR part 286 does not: (1) Have an annual effect on the economy of \$100 million or more or adversely affect in a material way the economy; a section of the economy; productivity; competition; jobs; the environment; public health or safety; or State, local, or tribal governments or communities; (2) Create a serious inconsistency or otherwise interfere with an action taken or planned by another Agency; (3) Materially alter the budgetary impact of entitlements, grants, user fees, or loan programs, or the rights and obligations of recipients thereof; or

means any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, his education, financial transactions, medical history, and criminal or employment history and that contains his name, or the identifying number, or symbol, or other identifying particular assigned to the individual, such as a finger or voice print or a photograph, as defined in the Privacy Act. Request for access to a record means a request made under subsection (d)(1) of the Privacy Act. Request for amendment or correction of a record means a request made under subsection (d)(2) of the Privacy Act. Request for an accounting means a request made under subsection (c)(3) of the Privacy Act. Requester means an individual who makes a request for access, a request for amendment or correction, or a request for an accounting under the Privacy Act. System of records means any group of records under the control of the Department of Defense from which information is retrieved by the name of the individual or by some other identifying number, symbol, or other identifying particular assigned to the individual as defined in the Privacy Act. Subpart B-Requests for Access and Amendment to Records §-310.3 Requesting access to records. (a) Individuals may request access to records in a system of records or request to be notified if a system of records contains records pertaining to them by writing to or appearing in person before the DoD Component that maintains the record. Written requests should be sent to the address listed in the record access procedures of the system of records notice (SORN) containing the record requested. If the name of the system of records or the address for the DoD Component that has the record is unknown, the individual may look up the SORN or the contact information for the DoD Component Privacy Office at <http://www.defense.gov/privacy>. (b) For access to the Official Personnel Files of federal civilian employees, which are maintained in the custody of the Department under the authority of the Office of Personnel Management (OPM) SORN OPM/GOVT-1, individuals must contact their DoD Component FOIA Requester Service Center. Contact information for DoD Component FOIA Requester Service Centers can be found at <https://www.foia.gov/report-makerequest.html>. (c) Requesters should provide their full name, current address and email address, and when requested in the access procedures of the applicable SORN, date of birth, place of birth, and telephone number, to assist the DoD Component in responding to the request and providing released records to the requester. The requester must sign the request and have it notarized or submit the request under 28 U.S.C. 1746

Supply Chain Raw materials are utilized to support the continuous operation of the manufacturing process. Raw materials are typically supplied through a long-term contract established with suppliers and are transported to the facility on a regular basis. Westman is committed to protecting its trade secrets, including product development, manufacturing processes, product quality, and supply chain management.

One comment asked whether the stipulation that CCIs must not disclose CMMC data or metrics applies to all data or only 'non-public' data. Consistency: One commenter asked for clarification regarding templates and formats required for information uploaded into the CMMC instantiation of eMASS. Response: The DoD has incorporated a request to delete the word 'enhance' from §-170.1(b), and the purpose of the CMMC Program now reads that the CMMC Program is designed as a compliance assessment

to assist in DoD's enforcement of information safeguarding requirements. Lower level paragraphs in § 170.3 have been reordered for added clarity. The words "and to the DoD via CMMC eMASS" have been added to the end of the Assessment Findings Report definition in § 170.4(b). In addition, § 170.9(b)(17) has been rephrased to stipulate that all assessment data and information uploaded into the CMMC instantiation of eMASS must be compliant with the data standard provided in the eMASS CMMC Assessment Import Templates available on the CMMC eMASS website. The DoD replaced the word "granting" with the word "conducting" in the description of C3PAO assessments in § 170.9(a). Sections 170.9(b)(9) and (b)(20) have been modified to eliminate redundancy between the two paragraphs, however the DoD did not concur that §§ 170.9(b)(17) and (18) are redundant and made no change. Section 170.18(c)(1)(i) was revised to clarify that the CMMC Assessment Scope for Level 3 must be equal to or a subset of the CMMC Assessment Scope for the Level 2 certification assessment of the system in question. Section 170.19 was revised to clarify that, for CMMC Level 2, OSAs will be assessed against all Level 2 requirements. For CMMC Level 3, OSAs will be assessed against all Level 2 and Level 3 requirements. Section 170.1 has been revised to correct punctuation and improve grammar. The section now conveys more clearly that the CMMC Program is designed as a compliance assessment to assist in DoD's enforcement of information safeguarding requirements. No changes were made regarding use of "not logically or physically isolated from all such CUI systems". Specifying a CMMC Assessment Scope is a necessary preparatory step for a CMMC assessment. Assessment requirements are specified in § 170.19. At Levels 2 and 3, logical or physical isolation is the primary mechanism used to separate in-scope from out-of-scope assets. CRMA and Specialized Asset categories only apply to assets that are within the Assessment Scope or boundary. § 170.6(b) has been revised to reference DFARS clause 252.204-7020 rather than DFARS clause 252.204-7012. In addition, § 170.05 was revised to reference DFARS clause 252.204-7012, rather than DFARS 204.73, for consistency and clarity. The title of § 170.16(c)(1) has been updated to specify self-assessment of the OSA. DoD declined to make other administrative changes because they would not result in a substantive change.

. This proposed standard would require a regulated entity to establish and implement a plan for reducing the risks identified through its risk analysis activities. Specifically, it would require a regulated entity to implement security measures sufficient to reduce risks and vulnerabilities to all ePHI to a reasonable and appropriate level. What would constitute a reasonable and appropriate level depends on the regulated entity's specific circumstances, including but not limited to its size, needs and capabilities, risk profile, the ability of security measures to reduce or eliminate a particular identified risk or vulnerability, and the ubiquity of such security measures. We also propose four implementation specifications that would require regulated entities to engage in activities that are consistent with previously issued guidance described below. Under the proposed implementation specification for planning at proposed paragraph (a)(5)(ii)(A), a regulated entity would be required to establish and implement a written risk management plan for reducing risks to all ePHI, including, but not limited to, those risks identified by the regulated entity's risk analysis, [500] to a reasonable and appropriate level. Proposed paragraph (a)(5)(i)(B) contains the proposed implementation specification for maintenance and would require the regulated entity to review the written risk management plan at least once every 12 months, and as reasonable and appropriate in response to changes in its risk analysis. The Department would interpret "reasonable and appropriate" in both paragraphs as requiring the regulated entity to take into account not only its specific circumstances, but also the criticality of the risks identified. We propose an implementation specification for priorities at proposed 45 CFR 164.308(a)(5)(ii)(C) that would require a regulated entity's written risk management plan to prioritize the risks identified in the regulated entity's risk analysis based on the risk levels determined by that analysis. Finally, in the proposed implementation specification for implementation at proposed 45 CFR 164.308(a)(5)(ii)(D) , we propose to require that a regulated entity implement security measures in a timely manner to address the risks identified in the regulated entity's risk analysis in accordance with the priorities established under paragraph (a)(5)(ii)(C). The proposed risk management standard aligns with the Department's essential CPG to Mitigate Known Vulnerabilities. [501] The Department previously issued guidance on risk management, including links to NIST resources, that is consistent with what we propose in this NPRM. [502] We encourage regulated entities to refer to similar NIST guidance for descriptions of risk management activities. [503]

Multiple comments recommended adding all the omitted requirements from NIST SP 800-172 Feb2021 or a subset including Network Intrusion Detection System, Deception and Unpredictability, arguing that they are necessary for protecting CUI and to defend against advanced persistent threats. Two

comments inferred that the requirement to restrict access to systems owned, provisioned or issued by the OSC means that the OSC must provide all equipment used to access the system, which they asserted is impossible because outside entities using GFE, to include DoD, may need access. One commenter also asked if DIB Furnished Equipment would be required, and one commenter argued for an exception for GFE, even though it is not owned, provisioned, or issued by the OSC. Three comments stated that Organizationally Defined Parameters (ODP) values need to be set by OSAs, not DoD. One commenter argued this will be necessary because of the emerging ODPs at Level 2 associated with NIST SP 800-171 Revision 3. One commenter argued this is critical for uniformity across the Federal enterprise as many contractors support multiple Federal agencies. The commenter further offered that allowing ODP values to be set by OSAs could be limited to contractor systems not operated on behalf of the DoD. One commenter suggested that ODP values set by OSAs may require approval by the contracting officer. One comment stated that the ODPs are too detailed for the 32 CFR part 170 CMMC Program rule, and table 1 to § 170.14 should be moved to the Level 3 Assessment Guide. One comment argued that removal or quarantine of components to facilitate patching or re-configuration, as specified in table 1 to § 170.14(c)(4) CM.L3-3.4.2e, is a disruptive and (printed page 83145) possibly a destructive operational constraint affecting business operations. They asserted that patching and reconfiguration are standard day-to-day IT administrative activity, and components do not need to be removed or quarantined. One comment asserted that CMMC should be based on NIST SP 800-53 R5 requirements (linked to the associated NIST SP 800-172 Feb2021 requirements) due to additional labor required to create NIST SP 800-53 R5 solutions and benefits to be gained from NIST SP 800-53 R5 overlays. Two comments argued that IA:L3-3.5.3e regarding 'the prohibition of system components from connecting to organizational systems unless certain conditions are met' is essentially the same requirement as CM:L2-3.4.7 'restricting, disabling, or preventing the use of nonessential programs, functions, ports, protocols, and services'. Response:

overall before attempting to define more specific relationships. 4. The direction of the mapping. A mapping could indicate how a concept in source A maps to a concept in source B, vice versa, or both. As Section 4 discusses, many mappings either have an obvious direction or are inherently directionless, so explicitly indicating the direction of mapping is often not necessary. 5. How exhaustive the mapping will be. An exhaustive mapping will not be necessary in most cases, such as mapping between concept systems in different domains (e.g., NICE Framework roles to Secure Software Development Framework [SSDF] categories) or at different levels of abstraction (e.g., CSF to SP 800-53 controls). Mapping indirect or tenuous relationships would create so many mappings that they would lose their value. Instead, we recommend capturing the strongest direct relationships between concepts. This helps keep the mapping clear and in line with the stated use case, targets the needs of the audience, and helps them prioritize their work.

The contractor will categorize the information system and the information processed, stored, and transmitted by the information system based on an impact analysis. Unless imposed by contract, the information system baseline is moderate-confidentiality, low-integrity, and low-availability. (3) Select. The contractor will select an initial set of baseline security controls for the information system based on the security categorization; tailoring and supplementing the security control baseline as needed based on an organizational assessment of risk and local conditions. (4) Implement. The contractor will implement the security controls and document how the controls are deployed within the information system and the operational environment. (5) Assess. The contractor will assess the security controls to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for the information system. The contractor will review and certify to the CSA that all systems have the appropriate protection measures in place. (6) Authorize. The CSA will use the information provided by the contractor to make a timely, credible, and risk-based decision to authorize the system to process classified information. The CSA must authorize the system before the contractor can use the system to process classified information. (7) Monitor. The contractor will monitor and assess selected security controls in the information system on an ongoing basis: (i) Effectiveness of security controls. (ii) Documentation of changes to the information system and the operational environment. (iii) Analysis of the security impact of changes to the information system. (iv) Making appropriate reports to the CSA. (f) Unclassified information systems that process, store, or transmit CUI. While outside the requirements of the NISPOM, contractors will comply with contract requirements regarding contractor information systems that process, store, or transmit CUI. § 117.19 International security requirements. (a) General. This section provides information and procedures governing the protection of classified information

in international programs. (b) Disclosure of classified U.S. information to foreign interests. (1) Applicable federal law. The transfer of articles, services, and related data to a foreign person, within or outside the United States, or the movement of such material or information to any destination outside of the legal jurisdiction of the United States constitutes an export. Depending on the nature of the articles or data, most exports are pursuant to (1) 22 U.S.C. chapter 39, also known and referred to in this rule as the Arms Export Control Act, (2) 50 U.S.C. 4801 et seq., also known as the Export Control Reform Act of 2018, or (3) the AEA. This section applies to those exports that involve classified information. (2) Security agreements. (i) Bilateral security agreements (e.g.,

(b) The requirements of this part do not apply to government information systems operated by contractors or subcontractors on behalf of the Government. (c) CMMC Program requirements apply to all DoD solicitations and contracts pursuant to which a defense contractor or subcontractor will process, store, or transmit FCI or CUI on unclassified contractor information systems, including those for the acquisition of commercial items (except those exclusively for COTS items) valued at greater than the micro-purchase threshold except under the following circumstances: (1) The procurement occurs during Implementation Phase 1, 2, or 3 as described in paragraph (e) of this section, in which case CMMC Program requirements apply in accordance with the requirements for the relevant phase-in period; or (2) Application of CMMC Program requirements to a procurement or class of procurements may be waived in advance of the solicitation at the discretion of DoD in accordance with all applicable policies, procedures, and approval requirements. (d) DoD Program Managers or requiring activities are responsible for selecting the CMMC Level that will apply for a particular procurement or contract based upon the type of information, FCI or CUI, that will be processed on, stored on, or transmitted through a contractor information system. Application of the CMMC Level for subcontractors will be determined in accordance with § 170.23. (e) DoD is utilizing a phased approach for the inclusion of CMMC Program requirements in solicitations and contracts. Implementation of CMMC Program requirements will occur over four (4) phases: (1) Phase 1. Begins on the effective date of the CMMC revision to DFARS 252.204-7021. DoD intends to include CMMC Level 1 Self-Assessment or CMMC Level 2 Self-Assessment for all applicable DoD solicitations and contracts as a condition of contract award. DoD may, at its discretion, include CMMC Level 1 Self-Assessment or CMMC Level 2 Self-Assessment for applicable DoD solicitations and contracts as a condition to exercise an option period on a contract awarded prior to the effective date. DoD may (printed page 89120) also, at its discretion, include CMMC Level 2 Certification Assessment in place of CMMC Level 2 Self-Assessment for applicable DoD solicitations and contracts. (2) Phase 2. Begins six months following the start date of Phase 1. In addition to Phase 1 requirements, DoD intends to include CMMC Level 2 Certification Assessment all for applicable DoD solicitations and contracts as a condition of contract award. DoD may, at its discretion, delay the inclusion of CMMC Level 2 Certification Assessment to an option period instead of as a condition of contract award. DoD may also, at its discretion, include CMMC Level 3 Certification Assessment for applicable DoD solicitations and contracts. (3) Phase 3.

CIS Safeguard 10.4 · Configure Automatic Anti-Malware Scanning of Removable Media Configure anti-malware software to automatically scan removable media. Implementation Groups: 2,3 Asset Type: devices Security Function: detect Parent Control: Malware Defenses

Section 170.21 addresses rules for having a POA&M for the purposes of a CMMC assessment and satisfying contract eligibility requirements for CMMC. All POA&Ms must be closed within 180 days of the Conditional CMMC Status Date. To satisfy CMMC Level 1 requirements, a POA&M is not allowed. To satisfy CMMC Level 2 requirements, a POA&M is allowed. Section 170.21 details the overall minimum score that must be achieved (printed page 83103) and identifies the Level 2 security requirements that cannot have a POA&M and must be fully met at the time of the assessment. To satisfy CMMC Level 3 requirements, a POA&M is allowed. Section 170.21 details the overall minimum score that must be achieved and identifies the Level 3 security requirements that cannot have a POA&M and must be fully met at the time of the assessment. Section 170.21 also established rules for closing POA&Ms. Section 170.22·Affirmation Section 170.22 addresses that the OSA's Affirming Official must affirm, in SPRS, compliance with the CMMC Status: upon completion of any self-assessment, certification assessment, or POA&M closeout assessment (as applicable), and annually following a Final CMMC Status Date. Section 170.23·Application to Subcontractors Section 170.23 addresses flow down of CMMC requirements from the prime contractor to the subcontractors in the supply chain. Prime contractors shall comply and shall require subcontractor compliance throughout

the supply chain at all tiers with the applicable CMMC Level for each subcontract as addressed in § 170.23(a). Section 170.24-CMMC Scoring Methodology Section 170.24 addresses the assessment finding types MET, NOT MET, and NOT APPLICABLE (N/A) in the context of CMMC assessments, and the CMMC Scoring Methodology used to measure the implementation status of security requirements for CMMC Level 2 and CMMC Level 3. Scoring is not calculated for CMMC Level 1 since all requirements must be MET at the time of assessment. For CMMC Level 2, the maximum score is the total number of Level 2 security requirements and is the starting value for assessment scoring. Any security requirement that has one or more NOT MET objectives reduces the current score by the value of the specific security requirement. Values for each CMMC Level 2 requirement are enumerated in § 170.24(c)(2)(i)(B). For CMMC Level 3, the maximum score is the total number of Level 3 security requirements and is the starting value for assessment scoring. Any security requirement that has one or more NOT MET objectives reduces the current score by the value of the specific security requirement. CMMC Level 3 does not use varying values; the value for each requirement is one (1), as described in § 170.24(c)(3). Appendix A to Part 170: Guidance Appendix A lists the guidance documents that are available to support defense contractors and the CMMC Ecosystem in the implementation and assessment of CMMC requirements. Discussion of Public Comments and Resulting Changes

Contribution of This NOI to the Internet Policy Task Force: Responses to this Notice will assist the Department's Internet Policy Task Force in preparing a report on cybersecurity, innovation and the Internet economy. The primary purposes of the report will be to identify and evaluate cybersecurity challenges facing commercial actors and consumers outside the critical infrastructure and key resources sectors to analyze various approaches to meet those challenges. The Department would also like to know how it can improve its execution of core cybersecurity responsibilities, including those supporting CIKR sectors and their customers. The Task Force's report may include options and recommendations for changes in public policy, as well as recommendations for voluntary steps that will enhance the commercial sector's and consumers' cybersecurity preparedness. The Task Force is hopeful that the dialogue launched here and the responses to this inquiry will contribute to Administration-wide policy positions and global cybersecurity strategy. Request for Comment The primary focus of this inquiry, as reflected above and in the questions listed below, is on enhancing the cybersecurity practices of commercial actors, consumers, and citizens outside the CIKR sectors. Activities involving government systems, other critical infrastructures and key resources receive attention from the Department of Homeland Security and other agencies. As such, they are not the main subject of this inquiry. The questions below are intended to help frame the issues and should not be construed as a limitation on comments that parties may submit. Comments containing references, studies, research, and other empirical data that are not widely published should include copies of the referenced materials. Comments will be posted at <http://www.ntia.doc.gov/internetpolicytaskforce> and <http://csrc.nist.gov>. 1. Quantifying the Economic Impact Prior to releasing this NOI, the Task Force conducted listening sessions with a wide range of stakeholders in order to understand the issues that have the greatest bearing on cybersecurity preparedness and continued growth of the Internet economy. During those conversations, the Task Force heard that while cybersecurity threats continue to pose challenges for Internet users and services providers, it appears difficult to assess the macro- and microeconomic impact of cybersecurity incidents with current tools. It is hard to manage that which one cannot measure. Losses related to Internet fraud (e.g.,

The SBA size thresholds are discussed in Section V.C. Regulatory Flexibility Act-Small Entity Analysis of this NPRM. The Department also estimated the percentage of rural and urban health care providers by matching health care provider data from CMS, [951] Health Resources & Services Administration, [952] and the Statistics of U.S. Businesses (SUSB) [953] with county population data from the U.S. Census Bureau. [954] We determined whether a health care provider was rural or urban based on OMB's standards for delineating metropolitan and micropolitan statistical areas. [955] Consistent with OMB's standard, we considered a county to be rural if it has fewer than 50,000 inhabitants. [956] This includes micropolitan areas (towns and cities between 10,000 and 49,999) and counties outside of metropolitan statistical areas and micropolitan areas. Based on this analysis, we estimate that 7-8 percent of health care providers operate in rural areas. Estimated Number and Type of Business Associates The Department adopts the estimate of approximately 1,000,000 business associates (including subcontractors) as stated in the 2024 ICR and the 2013 Modifications to the HIPAA Privacy, Security, Enforcement, and Breach Notification Rules Under the Health Information Technology for Economic and Clinical Health [HITECH] Act and the

Genetic Information Nondiscrimination Act, and Other Modifications to the HIPAA Rules· final rule.

[957] We considered whether to increase this figure in our updates but did not do so because many business associates serve multiple covered entities. We lack sufficient data to estimate the number of such businesses more precisely, but we believe that the number of business associates is highly dynamic and dependent on multiple market factors, including expansion and consolidation among various lines of business, changing laws and legal interpretations, and emerging technologies. We include subcontractors of business associates within our estimate because they are business associates of business associates. The Department welcomes comments on the number or type(s) of regulated entities that would be affected by the proposals in this proposed rule and the extent to which they may experience costs or other burdens not already accounted for in the cost estimates. The Department also requests comment on the number of health plan documents that would need to be revised, if any. The Department additionally requests detailed comment on any situations, other than those identified here, in which covered entities or business associates would be affected by the proposals in this rulemaking. Health Plan Sponsors Within this NPRM, the Department is for the first time including estimates of health plan sponsors' potential costs of compliance with specific (printed page 997)

(2) If a portion of the record contains information that is exempt from access, an extract or summary containing all of the information in the record that is releasable shall be prepared. (3) When the physical condition of the record or its state makes it necessary to prepare an extract for release, ensure the extract can be understood by the requester. (4) Explain to the requester all deletions or changes to the records. (f) Access to medical records. (1) Access to medical records is not only governed by the access provisions of this part but also by the access provisions of DoD 6025.18-R. The Privacy Act, as implemented by this part, however, provides greater access to an individual's medical record than that authorized by DoD 6025.18-R. (2) Medical records in a system of records shall be disclosed to the individual to whom they pertain, even if a minor, but when it is believed that access to such records could have an adverse effect on the mental or physical health of the individual or may result in harm to a third party, the following special procedures apply. (i) If a determination is made in consultation with a medical doctor that release of the medical information may be harmful to the mental or physical health of the individual or to a third party, the Component shall: (A) Send the record to a physician named by the individual; and (B) In the transmittal letter to the physician explain why access by the individual without proper professional supervision could be harmful (unless it is obvious from the record). (ii) The Component shall not require the physician to request the records for the individual. (3) If the individual refuses or fails to designate a physician, the record shall not be provided. Such refusal of access is not considered a denial under the Privacy Act (see paragraph (a) of § 310.18). (4) If records are provided the designated physician, but the physician declines or refuses to provide the records to the individual, the DoD Component is under an affirmative duty to take action to deliver the records to the individual by whatever means deemed appropriate. Such action should be taken expeditiously especially if there has been a significant delay between the time the records were furnished the physician and the decision by the physician not to release the records. (5) Access to a minor's medical records may be granted to his or her parents or legal guardians. However, access is subject to the restrictions as set forth at paragraph C9.7.3 of DoD 6025.18-R. (6) All members of the Military Services and all married persons are not considered minors regardless of age, and the parents of these individual do not have access to their medical records without written consent of the individual. (g) Access to information compiled in anticipation of civil action (see § 310.27). (h) Non-Agency Records.

aim is valid. There are also legislative restrictions regarding certain types of technology, such as cryptography, that require federal agencies to use only tested and validated cryptographic modules. Federal agencies, industry, and the public rely on cryptography for the protection of information and communications used in electronic commerce, critical infrastructure, and other application areas. At the core of all products offering cryptographic services is the cryptographic module. Cryptographic modules, which contain cryptographic algorithms, are used in products and systems to provide security services such as confidentiality, integrity, and authentication. Although cryptography is used to provide security, weaknesses such as poor design or weak algorithms can render the product insecure and place highly sensitive information at risk. Adequate testing and validation of the cryptographic module and its underlying cryptographic algorithms against established standards is essential to provide security assurance.

(A) Pursuant to a submission received before March 29, 2023, provided that the covered entity or business associate deploys in a timely manner any updates or patches required or recommended by the manufacturer of the device. (B) Pursuant to a submission received on or after March 29, 2023, where the device is no longer supported by its manufacturer, provided that the covered entity or business associate has deployed any updates or patches required or recommended by the manufacturer of the device. (C) Pursuant to a submission received on or after March 29, 2023, where the device is supported by its manufacturer. (4) Alternative measures. (i) Alternative measures. Where an exception at paragraph (b)(3) of this section applies, a covered entity or business associate must document in real-time the existence of an applicable exception and implement reasonable and appropriate compensating controls in accordance with paragraph (b)(4)(ii) of this section. (ii) Compensating controls. (A) To the extent that a covered entity or business associate determines that an exception at paragraph (b)(3)(i), (ii), or (iii) or (b)(3)(iv)(A) or (B) of this section applies, the covered entity or business associate must secure such electronic protected health information by implementing reasonable and appropriate compensating controls reviewed and approved by the covered entity's or business associate's designated Security Official. (B) To the extent that a covered entity or business associate determines that an exception at paragraph (b)(3)(iv)(C) of this section applies, the covered entity or business associate shall be presumed to have implemented reasonable and appropriate compensating controls where the covered entity or business associate has deployed the security measures prescribed and as instructed by the authorized label for the device, including any updates or patches recommended or required by the manufacturer of the device. (C) To the extent that a covered entity or business associate is implementing compensating controls under this paragraph (b)(4)(ii), the implementation and effectiveness of compensating controls must be reviewed, documented, and signed by the designated Security Official at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, to continue securing electronic protected health information and relevant electronic information systems. (printed page 1018) (5) Maintenance. Review and test the effectiveness of the technical controls required by this paragraph (b) at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. (c) Standard: Configuration management. (1) General.

·Revise § 170.12(b)(5) to state that CCIs may serve on an assessment team for a student's company, provided the CCI does not provide consulting to an OSC during delivery of the CMMC Instruction or breach other conflict of interest rules, and add that the CCI must be a currently certified CCA and conduct at least one certified or mock assessment under the direction of a C3PAO annually. ·Revise § 170.12(b)(6) to allow CCIs to craft exam objectives and content, as CCIs are the most in tune with issues faced by candidate CCPs and CCAs. ·Strike § 170.12 altogether, because potential Col concerns will be rare and can be managed by existing conflicts of interest mechanisms; clarify that while serving as a CMMC instructor means limited only to while actively teaching or any time while the person holds the CCI certification; and that Col concerns could be addressed by the addition of an Instructor Code of Conduct. One commenter also suggested this section would significantly decrease the available pool of CMMC instructors, as they would be forced to choose between instructing and consulting, which may be a more lucrative option. They also claimed it prevented CCIs who teach CCP/CCA courses at night from providing consulting services during the day. ·Impose a three- or four-year prohibition on ecosystem members from participating in the CMMC assessment process for an assessment in which they previously served as a consultant or since the OSC last obtained CMMC certification, whichever is most recent. ·Add language to §§ 170.11 and 170.13 to clarify if an individual consults with a defense industrial base company, they are prohibited from participating as a CMMC assessor for that same company. ·Update § 170.8(b)(ii)(17)(ii)(G) and add a time limit to this requirement to ensure a consultant can perform assessments, given an appropriate amount of time has passed. ·Revise § 170.8(b)(17)(ii)(G) to say, Prohibit CMMC Ecosystem members from participating in the CMMC assessment process for a CMMC assessment in which they previously served as an employee or consultant to prepare the organization for any CMMC assessment, as both an OSC employee and a CCPA/CCP serving as a consultant would face identical Col. ·Provide more detail on the scope of CCA and CCP conflict of interest disclosure required, particularly around the definition of process, store, or transmit in § 170.4(b). ·More narrowly tailor the Col requirement in § 170.8(b)(17)(i)(D) and more expressly identify the perceived conflicts of interest scenarios to help ecosystem members avoid legal risk. ·Rewrite § 170.8(b)(17)(iii)(C) to clarify what constitutes a satisfactory record of integrity and business ethics. ·Provide more detail in § 170.10(b)(11) on the term separation of duties, so CCAs know whether they can volunteer to develop test questions or provide training. Response

Summary:

AC.L2-3.1.1 · Authorized Access Control [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13

15 DISCUSSION [NIST SP 800-171 REV. 2]12 Access control policies (e.g., identity - or role-based policies, control matrices, and cryptography) control access between active entities or subjects (i.e., users or processes acting on behalf of users) and passive entities or objects (e.g., devices, files, records, and domains) in systems. Access enforcement mechanisms can be employed at the application and service level to provide increased information security. Other systems include systems internal and external to the organization. This requirement focuses on account management for systems and applications. The definition of and enforcement of access authorizations, other than those determined by account type (e.g., privileged versus [sic] non-privileged) are addressed in requirement 3.1.2 (AC.L2-3.1.2). FURTHER DISCUSSION Identify users, processes, and devices that are allowed to use company computers and can log on to the company network. Automated updates and other automatic processes should be associated with the user who initiated (authorized) the process. Limit the devices (e.g., printers) that can be accessed by company computers. Set up your system so that only authorized users, processes, and devices can access the company network. This requirement, AC.L2-3.1.1, controls system access based on user, process, or device identity. AC.L2-3.1.1 leverages IA.L2-3.5.1 which provides a vetted and trusted identity for access control. Example 1 Your company maintains a list of all personnel authorized to use company information systems, including those that store, process, and transmit CUI [a]. This list is used to support identification and authentication activities conducted by IT when authorizing access to systems [a,d]. Example 2 A coworker wants to buy a new multi-function printer/scanner/fax device and make it available on the company network within the CUI enclave. You explain that the company controls system and device access to the network and will prevent network access by unauthorized systems and devices [c]. You help the coworker submit a ticket that asks for the printer to be granted access to the network, and appropriate leadership approves the device [f]. Potential Assessment Considerations · Is a list of authorized users maintained that defines their identities and roles [a]? · Are account requests authorized before system access is granted [d,e,f]? 12 NIST SP 800-171 Rev. 2, p. 10.

TRICARE Management Activity, Attention: Freedom of Information Act Officer, 16401 East Centretech Parkway, Aurora, CO 80011-9043. <http://www.tricare.mil/tmaprivacy/foia.cfm> . AP2.3.2. Chairman, Armed Services Board of Contract Appeals. Chairman, Armed Services Board of Contract Appeals, Skyline Six Room 703, 5109 Leesburg Pike, Falls Church, VA 22041-3208. AP2.3.3. Defense Technical Information Center. Defense Technical Information Center, Attn: FOIA Program Manager, 8725 John J. Kingman Road, Suite 0944, Fort Belvoir, VA 22062-6218. <http://www.dtic.mil/dtic/foia/> . AP2.3.4 DoD Education Activity. DoD Education Activity, Freedom of Information Act Officer, 4040 North Fairfax Dr., Arlington, VA 22203-1635. <http://www.dodea.edu/foia/> . AP2.3.5. U.S. Central Command. U.S. Central Command, CCJ6-RD (FOIA), 7115 South Boundary Blvd., MacDill Air Force Base, FL 33621-5101. <http://www.centcom.mil/sites/foia/default.aspx> . AP2.3.6. U.S. European Command. U.S. European Command, FOIA Requester Service Center, Unit 30400 Box 1000, APO AE 09131. <http://www.eucom.mil/english/FOIA/main.asp> . AP2.3.7. U.S. Joint Forces Command. U.S. Joint Forces Command, Code J024, 1526 Mitscher Ave., Ste. 200, Norfolk, VA 23511-5100. <http://www.jfcom.mil/about/foia.htm> . AP2.3.8. U.S. Northern Command. U.S. Northern Command, FOIA Officer, 250 Vandenberg Street, Suite B016, Peterson Air Force Base, CO 80914-38040. <http://www.northcom.mil/foia/home.htm> . AP2.3.9. U.S. Pacific Command. U.S. Pacific Command, J151 FOIA, Box 64017, Camp H. M. Smith, HI 96861-4017. <http://www.pacom.mil/foia/homepage.shtml> . AP2.3.10. U.S. Southern Command. U.S. Southern Command, SCJ1-A (FOIA), 3511 NW .91st Avenue, Miami, FL 33172-1217. <http://www.southcom.mil/AppsSC/pages/foia.php> . AP2.3.11. U.S. Special Operations Command. U.S. Special Operations Command, SOCS-SJS-I/FOIA Requester Service Center, 7701 Tampa Point Blvd., MacDill Air Force Base, FL 33621-5323. <http://www.socom.mil/foia/> . AP2.3.12. U.S. Strategic Command. U.S. Strategic Command, Attn: J01031 (FOIA), 901 SAC Blvd., Suite 1E5, Offutt Air Force Base, NE 68113-6000. <http://www.stratcom.mil/foia/> . AP2.3.13. U.S. Transportation Command. U.S. Transportation Command, Attn: TCCS-IM, 508 Scott Drive, Scott Air Force Base, IL 62225-5357. <http://www.transcom.mil/foia.cfm> . AP2.4. National Guard Bureau The National Guard Bureau FOIA Requester Service Center is unique in that it processes its own initial FOIA requests; however, FOIA appeals are handled either by the Department of the Army or the Department of the Air Force. The address is: Chief, National Guard Bureau, Attn: NGB-SDA (FOIA), 1411 Jefferson Davis Highway, Arlington, VA 22202-3231.

<http://www.ngb.army.mil/sitelinks/foia.aspx> . Dated: December 11, 2007. L.M. Bynum, Alternate OSD Federal Register Liaison Officer, DoD. Footnotes 1. Copies of unclassified DoD issuances may be obtained at <http://www.dtic.mil/whs/directives/> . Back to Citation 2. Copies of Homeland Security Presidential Directive can be viewed at

The information in digital certificates is digitally signed by a certificate authority. This signature is the certificate authority's way of attesting that the individual (or system) in the identifier field is the true owner of the public key found in the certificate. The EAC's Election Management Guidelines [28] and the Ballot Preparation/Print and Pre-Election testing Quick Start Guide [30] provide some best practices that may help jurisdictions identify procedures for preparing ballots prior to an election. - [1] National Institute of Standards and Technology Interagency Report 7551, A Threat Analysis on UOCAVA Voting Systems , December 2008. <http://vote.nist.gov> - [2] Draft National Institute of Standards and Technology Interagency Report 7682, Information System Security Best Practices for UOCAVA Supporting Systems , April 2011. <http://vote.nist.gov> - [3] EAC. (2010). UOCAVA Pilot Program Testing Requirements, March 24, 2010. Accessed May 10, 2010 at <http://www.eac.gov/programareas/voting-systems/docs/requirements-03-24-10-uocava-pilotprogram> - [4] FVAP. (2010). Federal Post Card Application. Accessed May 10, 2010 at <http://www.fvap.gov/resources/media/fpca.pdf> - [5] Testimony of Bob Carey, Director of FVAP. (2010) EAC Public Meeting, Dec. 3 2009. Accessed April 5, 2010 at http://www.eac.gov/public_meeting/_12032010/ - [6] National Institute of Standards and Technology Interagency Report 7770. Security Considerations for Remote Electronic UOCAVA Voting . Whitepaper for the Technical Guidelines Development Committee. February 2011. - [7] Internet Engineering Task Force. (2010). S/MIME Mail Security. Accessed April 3, 2011 at <http://www.ietf.org/wg/concluded/smime.html> - [8] Callas, J., Donnerhake, L., Finney, H. and R. Thayer, 'OpenPGP Message Format', RFC 2240, November 1998. - [9] NIST SP 800-45 Version 2. Guidelines on Electronic Mail Security, February 2007 - [10] Hansen, T., et.

3.1.2 | 3. 3.1.2 Security Objectives and Types of Potential Losses As reflected in Table 1, FISMA and FIPS 199 define three security objectives for information and information systems. 3.1.2, the organizational entity responsible for impact determination must assign impact levels and consequent security categorization for the missionbased and management and support information types identified for each information system.

We assume that the potential records destroyed (after retention requirements have been met) as a result of the access requirement would be from the set of establishments with the poorest food safety practices. To determine the percent of firms with the poorest food safety practices, we obtained information from FDA personnel indicating that inspections of approximately 3 to 4 percent of all FDA-regulated food and cosmetic facilities from 2001 to 2003 were classified as official action indicated (Ref. 20). Based on this information, we assume that the incentive for records destruction will result in approximately 3 to 4 percent of firms destroying their records after 24 months, with destruction taking place shortly after retention commitments have been met. (printed page 71630) We assume that the private utility of records decreases over time, and that the rate at which records subject to 6 months retention are destroyed shortly after meeting the retention requirement is half that for records subject to 12 months retention, which is half that for records subject to 24 months retention. Consequently, an estimated 0.5 percent of records subject to the 6 month retention time are assumed to be destroyed shortly after the 6 months have been met (i.e., the solution for $\cdot X \cdot$ when solving the algebraic problem, $3.5 \text{ percent} = X + 2X + 4X$, where 3.5 percent is the midpoint between 3 and 4 percent and the rate at which all records are destroyed, X is the rate that records subject to the 6 month retention requirements are destroyed, $2X$ is the rate that records subject to 12 month retention requirements are destroyed, and $4X$ is the rate that records subject to the 24 month retention requirements are destroyed.). The destruction of records is estimated to affect about 0.02 percent of access requests (i.e., 0.5 percent records destruction rate x 3.3 percent of records requests made after 6 months). Finally, we assume that records destruction will slow down and terminate traceback investigations at the same rates at which the destruction takes place. Consequently, we estimate that both traceback speeds and rates of successful traceback completions will decline by 0.02 percent because of access requests when the requested records had been destroyed because of retention requirements. c. Extending the compliance dates

5. The 1965 Brooks Act gave the National Bureau of Standards (now NIST) responsibilities for

federal information technology standards. Public Law 89-306 (Oct. 30, 1965). The Computer Security Act of 1987 reaffirmed the responsibilities of NIST for the security of unclassified, non-military government computer systems. Public Law. 100-235 (Jan. 8, 1988). Under the law, the role of the National Security Agency (NSA) was limited in the civilian security realm to providing technical assistance. The 2002 Cyber Security Research and Development Act authorized funding to NIST for computer and network security research and established status reporting requirements. Public Law 107-305 (Nov. 27, 2002). The 2002 Federal Information Security Management Act provided for development and maintenance by NIST of minimum controls required to protect federal information and information systems. Title III of Public Law 107-347 (Dec. 17, 2002). Back to Citation 6.

See 47 U.S.C. 902 (b)(2)(D) (providing that NTIA has "[t]he authority to serve as the President's principal adviser on telecommunications policies pertaining to the Nation's economic and technological advancement and to the regulation of the telecommunications industry."); see also Federal Communications Commission, *Connecting America: The National Broadband Plan*, at 55 (2010), <http://download.broadband.gov/plan/national-broadband-plan.pdf>. In 1993, the White House formed the Information Infrastructure Task Force (White House Task Force), chaired by the Secretary of Commerce, to develop telecommunications and information policies to promote the development of the Internet. In 1997, the White House Clinton Administration published *A Framework for Global Electronic Commerce*. This was the work of an interagency working group of high level representatives of several cabinet agencies, including the Departments of Treasury, State, Justice and Commerce, as well as the Executive Office of the President, including the Council of Economic Advisors, the National Security Council, the Office of Science and Technology Policy, the Office of the Vice President, and the U.S. Trade Representative. Independent commissions including the Federal Communications Commission and the Federal Trade Commission also contributed to the working group. In several instances, the Framework notes NTIA's collaborative efforts, in conjunction with other federal agencies, such as the State Department, Federal Trade Commission, U.S. Trade Representative, to explore opportunities for international cooperation to protect consumers and to prosecute false, deceptive, and fraudulent commercial practices in cyberspace. President William J. Clinton and Vice President Albert Gore, Jr., *A Framework for Global Electronic Commerce* (1997) (pagination not available), <http://clinton4.nara.gov/WH/New/Commerce/>; see also Memorandum on Electronic Commerce, 33 Weekly Comp. Pres. Doc 1006 (July 1, 1997). Back to Citation

3.3.1 Current Authentication Practice... 3.3.1 Current Authentication Practice The most common and critical form of communication, voice communication via LMR, does not require authentication, as described in Section 2.

The Security Rule does not currently include a definition for the term "risk." The Department considered defining it when it first promulgated the final rule in 2003, but declined to do so because it determined that the term was commonly understood. [379] However, the Department now believes that the lack of a definition may affect the clarity of some key requirements for regulated entities. Such requirements include conducting a risk analysis to assess the potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI held by the regulated entity [380] and implementing security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with the general rules at 45 CFR 164.306(a) . [381] One of the ways NIST defines the term is as "a measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of: (i) the adverse impacts that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence." [382] This and other NIST definitions serve as helpful references for the Department when considering how to define the term within the rule.

b. Proposal The Department proposes to define "risk" as the extent to which the confidentiality, integrity, or availability of ePHI is threatened by a potential circumstance or event. The Department believes that defining the term would clarify several existing and proposed provisions of the Security Rule, such as the factors regulated entities must consider when determining the security measures they will implement [383] and the importance and purpose of conducting the required risk analysis. [384] 15.

Clarifying the Definitions of "Security or Security Measures" and "Security Incident"

a. Current Provision and Issues To Address The Security Rule defines "security or security measures" as encompassing all of the administrative, physical, and technical safeguards in an information system. [385] The definition implies that the safeguards must be part of the information system, as opposed to something that may be applied or done to a system to protect the confidentiality, integrity, and availability of ePHI.

From the NIST SP 800-172 Rev 3 Final Public Draft: confidentiality 2852 Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information. [20] configuration management A collection of activities focused on establishing and maintaining the integrity of information technology products and systems through the control of processes for initializing, changing, and monitoring the configurations of those products and systems throughout the system development life cycle. configuration settings The set of parameters that can be changed in hardware, software, or firmware that affect the security posture or functionality of the system. controlled unclassified information Information that law, regulation, or government-wide policy requires to have safeguard

Security Improve with Age?, 15th USENIX Security Symposium, Vancouver, B.C., Canada, July 31-August 4, 2006, http://www.usenix.org/events/sec06/tech/full_papers/ozment/ozment.pdf - [Pay06] Shirley C. Payne, A Guide to Security Metrics, SANS Security Essentials GSEC Practical Assignment, Version 1.2e, June 19, 2006, http://www.sans.org/reading_room/whitepapers/auditing/55.php - [Pou08] Kevin Poulsen, Researchers Use PlayStation Cluster to Forge a Web Skeleton Key, Wired Magazine, December 30, 2008, <http://blog.wired.com/27bstroke6/2008/12/berlin.html> - [Qua98] Richard E. Quandt, Measurement and Inference in Wine Tasting, Meetings of the Vineyard Data Quantification Society, Ajaccio, Corsica, October 2-3, 1998, <http://www.liquidasset.com/corsica.htm> - [Rei07a] Gavin Reid, Peter Mell, Karen Scarfone, CVSS-SIG Version 2 History, Forum of Incident Response and Security Teams, June 13, 2007, <http://www.first.org/cvss/history.html> - [Rei07b] Mark Reith, Jianwei Niu, William Winsborough, Apply Model Checking To Security Analysis in Trust Management, C107-0030, University of Texas at San Antonio, January 2, 2007, <http://stinet.dtic.mil/cgibin/GetTRDoc?AD=ADA462754&Location=U2&doc=GetTRDoc.pdf> - [Ron02] Juha Rönning, Marko Laakso, Ari Takanen, Rauli Kaksonen, PROTOS Systematic Approach to Eliminate Software Vulnerabilities, Invited presentation at Microsoft Research, Seattle, Washington, May 6, 2002, <http://www.ee.oulu.fi/research/ouspg/protos/sota/MSR2002-protos/index.html> - [SAI07] Microsoft Windows Server 2003, XP Professional and XP Embedded Security Target, Version 3.0, Science Applications International Corporation, Common Criteria Testing Laboratory, November 19, 2007, http://www.commoncriteriportal.org/files/epfiles/20080303/st_vid10184-st.pdf

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 Every system and system component has a point of origin and may be changed 2585

141. · See ·Assessing resilience of hospitals to cyberattack,· supra note 130; Claire C. McGlave, et al., ·Hacked to Pieces? The Effects of Ransomware Attacks on Hospitals and Patients,· SSRN (Oct. 4, 2023), https://papers.ssrn.com/sol3/papers.cfm?abstract_id=4579292 . Back to Citation 142. ·Hacked to Pieces? The Effects of Ransomware Attacks on Hospitals and Patients,· supra note 141, p. 14. Back to Citation 143. ·The 2024 Study on Cyber Insecurity In Healthcare: The Cost and Impact on Patient Safety and Care,· Ponemon Institute, p. 3 (2024) (The report, sponsored by Proofpoint, Inc., included survey responses from 648 IT and IT security practitioners at U.S.-based health care organizations.) . Back to Citation 144. Id. at p. 5. Back to Citation 145. · See Letter from NCVHS Chair Jacki Monson (2023), supra note 123, p. 1 (citing several media reports that attributed patient deaths to cybersecurity attacks). Back to Citation 146. Id. (citing Joseph Marks, ·Ransomware attack might have caused another death,· The Washington Post (Oct. 1, 2021), <https://www.washingtonpost.com/politics/2021/10/01/ransomware-attack-might-have-caused-another-death/>). Back to Citation 147. ·Assessing resilience of hospitals to cyberattack,· supra note 130, p. 2. Back to Citation 148. ·Kerri Reeves, ·Cyberattacks: Not a Matter of If, but When,· Radiology Matters (Mar./Apr. 2024), <https://www.proquest.com/scholarly-journals/cyberattacks-not-matter-if-when/docview/2957757956/se-2?accountid=12786> . Back to Citation 149. Id. Back to Citation 150. ·Mitchell Tarka, et al., ·The crippling effects of a cyberattack at an academic level 1 trauma center: An orthopedic perspective,· Injury, p. 1095-1101 (2023), <https://pubmed.ncbi.nlm.nih.gov/36801172/> . Back to Citation 151. Id. Back to Citation 152. ·Assessing resilience of hospitals to cyberattack,· supra note 130, p. 13. Back to Citation 153. · See Paige Minemyer, ·AMA: 80% of docs have lost revenue amid disruptions from Change Healthcare cyberattack,· Fierce Healthcare (Apr. 10, 2024), <https://www.fiercehealthcare.com/practices/ama-80-docs-have-lost-revenue-amid-disruptions-change-healthcare-cyberattack> ; ·AHA survey: Change Healthcare cyberattack having significant disruptions on patient care, hospitals' finances· (Mar. 15, 2024),

<https://www.aha.org/news/news/2024-03-15-aha-survey-change-healthcare-cyberattack-having-significant-disruptions-patient-care-hospitals-finances> ; see also Sean Lyngaas, “We’re hemorrhaging money”: US health clinics try to stay open after unprecedented cyberattack, CNN (Mar. 9, 2024), <https://www.cnn.com/2024/03/09/tech/medical-supply-chain-cybersecurity/index.html> . Back to Citation 154. Christian Dameff, et al., Ransomware Attack Associated With Disruptions at Adjacent Emergency Departments in the U.S., JAMA Network Open (May 8, 2023), <https://jamanetwork.com/journals/jamanetworkopen/fullarticle/2804585> . Back to Citation 155. Id. Back to Citation

We revised the estimated costs of the final rule in response to comments on the proposed rule and to account for the changes between the proposed and final rules. The final rule will cover more (printed page 71612) than 1 million entities at a cost of approximately \$1.41 billion in present value with a 7-percent discount rate. With a discount rate of 3 percent, the estimated present value of the costs is approximately \$1.94 billion. Costs for learning, records redesign, and planning for records access requests are one-time costs incurred in the first 2 years following publication of the final rule. Additional records maintenance costs and records retention costs are incurred each year following publication of the rule beginning in the second year for large and small firms, and in the third year for very small firms. Learning costs and records access planning costs for new entrants are also incurred each year following publication of the final rule beginning after the second year. The total cost estimate can be computed by summing the costs estimated for learning, records redesign, additional records maintenance, records retention, and planning for a records access request. The annual and total costs of the final rule are reported in table 1 of this document. The recurring annual costs of the final rule (the sum of additional records maintenance and learning for new firms) are about \$123 million. The annualized costs of this final rule are \$108,000 using a 3-percent discount rate and \$110,000 using a 7-percent discount rate. Table 1. Estimated Annual and Total Recordkeeping Costs 1 21 CFR Section Costs (in dollars) 1.337, 1.345, and 1.352 (learning) \$85,082,000 1.337, 1.345, and 1.352 (records redesign) \$205,239,000 1.337, 1.345, and 1.352 (additional records maintenance) \$114,701,000 1.337, 1.345, and 1.352 (learning for new firms) \$8,508,200 Discounted present value of total costs 2 \$1,406,356,000 1 The annual costs are reported in undiscounted terms. Records access planning costs and records retention costs are estimated to be zero and are not reported here. 2 The reported discounted present value of total costs assumes a 7-percent discount rate and a 20-year time horizon over which annual costs are summed.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense General Services Administration National Aeronautics and Space Administration 48 CFR Parts 1, 2, 4, 52, and 53 [FAC 2020-07; FAR Case 2015-002; Item I; Docket No. FAR-2015-0002; Sequence No. 1] RIN 9000-AN40 AGENCY: Department of Defense (DoD), General Services Administration (GSA), and National Aeronautics and Space Administration (NASA). ACTION: Final rule. SUMMARY: DoD, GSA, and NASA are issuing a final rule amending the Federal Acquisition Regulation (FAR) to require electronic submission of the DD Form 254, Contract Security Classification Specification. DATES: Effective: August 3, 2020. FOR FURTHER INFORMATION CONTACT: Mr. Curtis E. Glover, Sr., Procurement Analyst, at 202-501-1448 or curtis.glover@gsa.gov for clarification of content. For information pertaining to status or publication schedules, contact the Regulatory Secretariat Division at 202-501-4755. Please cite FAR Case 2015-002. SUPPLEMENTARY INFORMATION: I. Background DoD, GSA, and NASA published a proposed rule in the Federal Register at 84 FR 33201 on July 12, 2019, proposing to amend the FAR to update and clarify the requirements for using the DD Form 254, Contract Security Classification Specification. This rule amends the FAR, in part, to provide procedures for use of the DD Form 254 and the requirement to use the Procurement Integrated Enterprise Environment (PIEE), to Streamline the submission process for the existing DD Form 254 and enable businesses to submit an electronic form once, instead of repeated paper submissions; Require use of the DD Form 254 by nondefense agencies that have industrial security services agreements with DoD, and DoD components, to specify the security classification for a contract involving access to information classified as Confidential, Secret, or Top Secret; Require agency preparation of the DD Form 254 using the National Industrial Security Program Contracts Classification System module of the PIEE unless a nondefense agency has an existing DD

Form 254 information system. Five respondents submitted comments on the proposed rule. II. Discussion and Analysis The Civilian Agency Acquisition Council and the Defense Acquisition Regulations Council (the Councils) reviewed the public comments in the development of the final rule. A discussion of the comments is provided as follows: A. Summary of Significant Changes

. Another policy option considers extending each of the proposed compliance dates by 6 months: Large, small, and very small firms would be required to be in compliance with the regulation 12, 18, and 24 months, respectively, after publication of the final rule instead of the proposed 6, 12, and 18 months after publication. The longer compliance dates reduce the time savings for a preventive action for 50 percent of the annual number of traceback investigations, and lead to a 50 percent increase in the annual number of outbreak investigations prematurely terminated for records quality reasons. Unlike the reduction in the benefits from the other policy options considered, these are one-time decreases in the benefits, because the option only extends the initial baseline compliance times by 6 months. d. Exemption of all very small entities . FDA also considered whether it should exempt all entities with ten or fewer employees, not just those in the retail sector as is provided in the final rule; however, this would create a ‘Swiss Cheese’ approach to trace back, as there would be a potential failure of entities to keep records throughout the distribution chain. The number of very small entities account for a large fraction of the total number of food establishments. Moreover, many of our failures in a typical trace back investigation (i.e., unclassified scenarios) have been at the wholesaler (distributor) level. As discussed above, we would have significant concerns if 90 percent of the transporters (as very small entities) would be excluded from the requirements to establish and maintain records, particularly if these are predominantly intrastate transporters that are not currently subject to DOT’s requirements. (FDA notes that intrastate shipments carried by interstate transporters also are not subject to DOT’s requirements.) In light of the above, FDA does not believe we would have an effective recordkeeping system if we were to exempt all very small entities from the rule. Unlike the very small retailers who are at the end of the distribution chain only, a full exemption by size would create holes throughout the distribution chain and would not provide FDA adequate assurances that, in the event of a threat of serious adverse health consequences or death to humans or animals, FDA would be able to conduct an efficient and effective traceback investigation. F. Costs 1. Estimates of the Number of Facilities Affected By the Final Rule In the PRIA, FDA estimated the number of transporters and packers from data in the 2000 County Business Pattern statistics (Ref. 21) and the 1999 Nonemployer statistics (NES) (Ref. 22). We assumed that local and long distance specialized freight carriers devoted exclusively to transporting food were about 20 percent of the total of the specialized freight category. In the PRIA, FDA requested comments on the assumption that 20 percent was appropriate for this estimate.

An authorized or accredited C3PAO must perform a Level 2 certification assessment in accordance with NIST SP 800-171A Jun2018 (incorporated by reference, see § 170.2) and the CMMC Level 2 scoping requirements set forth in § 170.19(a) and (c) for the information systems within the CMMC Assessment Scope. The Level 2 certification assessment must be scored in accordance with the CMMC Scoring Methodology described in § 170.24 and the C3PAO must upload the results into the CMMC instantiation of eMASS. Final results are communicated to the OSC through a CMMC Assessment Findings Report. (2) Security requirement re-evaluation. A security requirement that is NOT MET (as defined in § 170.24) may be re-evaluated during the course of the Level 2 certification assessment and for 10 business days following the active assessment period if all of the following conditions exist: (i) Additional evidence is available to demonstrate the security requirement has been MET; (ii) Cannot change or limit the effectiveness of other requirements that have been scored MET; and (iii) The CMMC Assessment Findings Report has not been delivered. (3) POA&M. If a POA&M exists, a POA&M closeout certification assessment must be performed by a C3PAO within 180-days of the Conditional CMMC Status Date. Additional guidance can be found in § 170.21 and in the guidance document listed in paragraph (c) of appendix A to this part. (4) Artifact retention and integrity. The hashed artifacts used as evidence for the assessment must be retained by the OSC for six (6) years from the CMMC Status Date. To ensure that the artifacts have not been altered, the OSC must hash the artifact files using a NIST-approved hashing algorithm. The OSC must provide the C3PAO with a list of the artifact names, the return value of the hashing algorithm, and the hashing algorithm for upload into the CMMC instantiation of eMASS. Additional guidance for hashing artifacts can be found in the guidance document listed in paragraph (h) of appendix A to this part. (5) Level 2 certification assessment with the use of Cloud Service Provider (CSP). An OSC may use a cloud environment to process, store, or transmit CUI in performance of a contract or subcontract with a requirement for

the CMMC Status of Level 2 (C3PAO) under the following circumstances: (i) The CSP product or service offering is FedRAMP Authorized at the (printed page 83230) FedRAMP Moderate (or higher) baseline in accordance with the FedRAMP Marketplace; or (ii) The CSP product or service offering is not FedRAMP Authorized at the FedRAMP Moderate (or higher) baseline but meets security requirements equivalent to those established by the FedRAMP Moderate (or higher) baseline. FedRAMP Moderate or FedRAMP Moderate equivalent is in accordance with DoD Policy.

Revision to Include Updates in Cybersecurity Framework Version 1.1 The Cybersecurity Framework Manufacturing Profile, NISTIR 8183, is scheduled to be revised to include the updates in the Cybersecurity Framework Version 1.1, and will be published as NISTIR 8183, Revision 1. Once NISTIR, 8183, Revision 1 has been released, this implementation guide will be revised to include the updates in the Cybersecurity Framework Version 1.1 as well, and will be published as NISTIR 8183A, Revision 1.

and NIST [SP 800-124]: Guidelines for Managing the Security of Mobile Devices in the Enterprise .
`` ## 4. Eliminate Unnecessary Ports, Services, and Protocols (Least Functionality) Devices are configured to allow only the necessary ports, protocols, and services in accordance with functional needs and the risk tolerance in the organization.

, (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record, and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, and to preserve the confidentiality and integrity of Federal evaluation materials. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . §-310.15 Department of the Army exemptions. (a) Special exemption. 5 U.S.C. 552a(d)(5) ·Denies individual access to any information compiled in reasonable anticipation of a civil action or proceeding. (b) General and specific exemptions. The Secretary of the Army may exempt Army systems of records from certain requirements of the Privacy Act of 1974. The two kinds of exemptions that require Secretary of the Army enactment are general and specific exemptions. The general exemption authorizes the exemption of a system of records from most requirements of the Act; the specific exemptions authorize the exemption of a system of record from only a few. (c) General exemptions. Only Army activities actually engaged in the enforcement of criminal laws as their principal function may claim the general exemption. See 5 U.S.C. 552a(j)(2) . To qualify for this exemption, a system must consist of: (1) Information compiled to identify individual criminal offenders and alleged offenders, which consists only of identifying data and arrest records; type and disposition of charges; sentencing, confinement, and release records; and parole and probation status; (2) Information compiled for the purpose of criminal investigation including reports of informants and investigators, and associated with an identifiable individual; or (printed page 14745) (3) Reports identifiable to an individual, compiled at any stage of the process of enforcement of the criminal laws, from arrest or indictment through release from supervision. (d) Specific exemptions. The Secretary of the Army has exempted all properly classified information and systems of records that have the following kinds of information listed in this section, from certain parts of the Privacy Act. The Privacy Act exemption reference appears in parentheses after each category.

Public comments received illustrate that some small businesses may be unaware of how to propose cybersecurity-related costs for cost-type contracts. This rule does not change existing contract cost principles or procedures. For firm-fixed priced efforts, market supply and demand dictates profitability and bid prices, and underlying costs are not itemized. 9. Disputes Regarding CMMC Assessments Comment: Multiple commenters asked about the CMMC assessment dispute resolution process, with regard to which standards would be followed, how much time would be available to appeal findings, the types of complaints that could be raised, any limits to the costs or schedule required for dispute resolution, and roles and responsibilities of the DoD, C3PAOs, and the Accreditation Body. Commenters also wanted to know whether a tiered recourse process would be

available to resolve contractor objections to the initial resolution. Two commenters expressed concerns regarding potential impacts of C3PAO assessment errors. Two commenters requested clarification regarding whether the CMMC Level required by the DoD or a prime contractor could be contested. Response: The CMMC assessment appeal process (formerly referred to as dispute resolution) described in the DFARS Case 2019-D041 Supplementary Information has changed and is described in § 170.9(b)(20) and § 170.8(b)(16). The appeals process is derived from and consistent with ISO/IEC 17020:2012 and ISO/IEC 17011:2017. Each C3PAO is required to have a time-bound, internal appeals process to address disputes related to perceived assessor errors, malfeasance, and unethical conduct. Requests for appeals will be reviewed and approved by individual(s) within the C3PAO not involved in the original assessment activities in question. OSCs can request a copy of the process from their C3PAO. If a dispute regarding assessment findings cannot be resolved by the C3PAO, it will be escalated to the Accreditation Body. The decision by the Accreditation Body will be final. A request for an appeal about an assessor's professional conduct that is not resolved with the C3PAO will be escalated and resolved by the Accreditation Body. The issue of C3PAO liability is between an OSC and the C3PAO with which it contracts to do the assessment. Any questions about the CMMC Level required by the solicitation should be directed to the contracting officer for the affected contractor. 10. Acceptance of Alternate Standards a. NIST SP 800-171 Rev 2 DoD Assessments and CMMC Assessments Comment: Multiple commenters asked for clarification on reciprocity between NIST SP 800-171 Rev 2 DoD Assessments and CMMC assessments. Response:

to clarify the organization of regulatory text and to clarify its longstanding expectations that policies and procedures must be in writing and to replace ·contain· with ·maintain,· consistent with terminology used throughout the HIPAA Rules. The Department believes that having written policies for the disposal of ePHI and the technology assets on which it is stored and for the removal of ePHI from electronic media such that the ePHI cannot be recovered continues to be important to ensuring the physical safety of ePHI. Improper disposal of technology assets puts the ePHI stored in or on such assets at risk for a potential breach, and as discussed elsewhere, data breaches can result in substantial costs to regulated entities and the individuals affected by the breach. We also propose in the related implementation specifications at 45 CFR 164.310(d)(2)(i) and (ii) to require that written policies and procedures for disposal of ePHI and sanitization of electronic media be tied to current standards for sanitizing electronic media before the media are made available for re-use. [653] For example, photocopiers today are often connected to the same network as workstations and generally store the information, including ePHI, transmitted to them. This capability is a significant change from photocopier capabilities that existed when the Security Rule was first issued in 2003. Under this proposal, a regulated entity would be required to include in its written policies and procedures for disposing of ePHI, and the technology assets on which it is maintained, policies and procedures addressing ePHI maintained on photocopiers, consistent with the current standards for disposing and removing ePHI from electronic media. [654] We have previously explained in guidance that a regulated entity should consider all of the following as part of its risk analysis: Disposal of hardware and software, and the documentation of such disposal. Destruction of ePHI in such a manner that it cannot be recreated. Secure removal of ePHI that was previously stored on hardware or electronic media such that it cannot be accessed and reused. The identification of all removable media and their use (e.g., CDs/DVDs, USB flash drives). (printed page 962) The removal of all ePHI from reusable media before the media are reused. [655] Our guidance describes these considerations in greater detail. For example, regulated entities should consider how to address the replacement of technology assets, including devices and media. [656] Technology assets that need to be replaced should be decommissioned, meaning that they are taken out of service before the final disposition of such assets. [657]

The Food and Drug Administration (FDA) is issuing final regulations pertaining to the dissemination of information on unapproved uses (also referred to as “new uses” and “off-label uses”) for marketed drugs, including biologics, and devices. The final rule describes the new use information that a manufacturer may disseminate and describes the content of and establishes procedures for a manufacturer's submission to FDA before it may begin disseminating information on the new use. The final rule also describes how manufacturers seeking to disseminate information on a new use must agree to submit a supplemental application for that use within a specified period of time, unless a supplemental application already has been submitted or FDA has exempted the manufacturer from the requirement to submit a supplement. The final rule provides for requests to extend the time period for submitting a supplemental application for a new use and describes how a manufacturer can seek an exemption from the requirement to submit a supplemental application for the new use. Additionally,

the final rule discusses FDA actions in response to manufacturers' submissions, corrective actions that FDA may take or require, and recordkeeping and reporting requirements. The final rule implements sections 551 through 557 of the Federal Food, Drug, and Cosmetic Act (the act) (21 U.S.C. 360aaa through 360aaa-6) as amended by section 401 of the Food and Drug Administration Modernization Act of 1997 (FDAMA).

(i) The DIB participants shall not share GFI outside of their company or organization, regardless of personnel clearance level, except as authorized in this part or otherwise authorized in writing by the Government. (j) If the DIB participant utilizes a third-party service provider (SP) for information system security services, the DIB participant may share GFI with that SP under the following conditions and as authorized in writing by the Government: (1) The DIB participant must identify the SP to the Government and request permission to share or disclose any GFI with that SP (which may include a request that the Government share information directly with the SP on behalf of the DIB participant) solely for the authorized purposes of this program; (2) The SP must provide the Government with sufficient information to enable the Government to determine whether the SP is eligible to receive such information, and possesses the capability to provide appropriate protections for the GFI; (3) Upon approval by the Government, the SP must enter into a legally binding agreement with the DIB participant (and also an appropriate agreement with the Government in any case in which the SP will receive or share information directly with the Government on behalf of the DIB participant) under which the SP is subject to all applicable requirements of this part and of any supplemental terms and conditions in the DIB participant's FA with the Government, and which authorizes the SP to use the GFI only as authorized by the Government. (k) The DIB participant may not sell, lease, license, or otherwise incorporate the GFI into its products or services, except that this does not prohibit a DIB participant from being appropriately designated an SP in accordance with paragraph (j) of this section. §.236.5 Cyber security information sharing. (a) GFI. The Government shall share GFI with DIB participants or designated SPs in accordance with this part. (b) Initial incident reporting. The DIB participant shall report to DC3/DCISE cyber incidents involving covered defense information on a covered DIB system. These initial reports will be provided within 72 hours of discovery. DIB participants also may report other cyber incidents to the Government if the DIB participant determines the incident may be relevant to information assurance for covered defense information or covered DIB systems or other information assurance activities of the Government. (c) Follow-up reporting. After an initial incident report, the Government and the DIB participant may voluntarily (printed page 62437) share additional information that is determined to be relevant to a reported incident, including information regarding forensic analyses, mitigation and remediation, and cyber intrusion damage assessments. (d) Cyber intrusion damage assessment.

AU.L2-3.3.1 · System Auditing CMMC Assessment Guide · Level 2 | Version 2.13 74 In defining the audit log retention period, OSAs must ensure that logs are retained for a sufficiently long period to allow for the investigation of a security event. The retention period must take into account the delay of weeks or months that can occur between an initial compromise and the discovery of attacker activity. Example You set up audit logging capability for your company. You determine that all systems that contain CUI must have extra detail in the audit logs. Because of this, you configure these systems to log the following information for all user actions [b,c]: · time stamps; · source and destination addresses; · user or process identifiers; · event descriptions; · success or fail indications; and · filenames. Potential Assessment Considerations · Are audit log retention requirements appropriate to the system and its associated level of risk [e]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.3.1

- . Office of Management and Budget (OMB) policy decisions - . Congressional legislation - . Selection of categories within major Department of Defense efforts such as the Corporate Information Management (CIM) and/or Computer-aided Acquisition and Logistics Support (CALS) Noel Nazario (NIST) summarized the developments in the labeling effort since the previous workshop. These include: Ron Sharp (AT&T) represented the Trusted Systems Interoperability Group (TSIG) . Mr. Sharp described the TSIG as a very informal group of implementors interested in developing interoperable trusted distributed systems. The TSIG is engaged in projects such as CIPSO, Trusted X-Windows, Trusted Network File Systems (NFS), Trusted Session Management, and Trusted Sockets. The current focus for TSIG members is the TCP/IP communications protocol but the door remains open for a transition to OSI as markets emerge. In developing CIPSO the TSIG adopted and modified original work done by Sun Microsystems and Hewlett-Packard. The group has spawned an Internet Working Group whose purpose is

to present CIPSO as an Internet Request for Comment (RFC) . Mr. Sharp enumerated reasons for the development of CIPSO, its main features, and presented the label format. His presentation slides and the current version of the CIPSO specification appears on page 55 of this document.

The speakers specialize in cyber attack methods, attack warning and detection, and cyber countermeasures. They have presented numerous talks on cloud forensics, cyber adversaries and advanced persistent threats to a wide range of public and government audiences.

CA.L2-3.12.2 · operational Plan of Action CMMC Assessment Guide · Level 2 | Version 2.13 204

FURTHER DISCUSSION When you write a plan of action, define the clear goal or objective of the plan.

You may include the following in the action plan: · ownership of who is accountable for ensuring the plan's performance; · specific steps or milestones that are clear and actionable; · assigned responsibility for each step or milestone; · milestones to measure plan progress; and · completion dates. This requirement, CA.L2 -3.12.2, which ensures developing and implementing operational plans of action to correct and reduce vulnerabilities in systems, is driven by risk management requirement RA.L2-3.11.1, which promotes periodically assessing risk to organizational systems. CA.L2-3.12.2 promotes monitoring security controls on an ongoing basis as defined in requirement CA.L2-3.12.3. An operational plan of action in accordance with CA.L2 -3.12.2 differs from a CMMC assessment POA&M as described in 32 CFR § 170.21. The assessment POA &M places conditions on which security requirements can be assessed as NOT MET and allows the OSA to qualify for a CMMC Status of Conditional Level 2 (Self), Conditional Level 2 (C3PAO), or Conditional Level 3 (DIBCAC) . Operational plans of action are not subject to the 180 day POA&M closeout requirement. Severity, availability of remediation, and business requirements are among the factors to consider when creating and maintaining operational plans of action. Example As IT director, one of your duties is to develop action plans when you discover that your company is not meeting security requirements or when a security issue arises [b]. A recent vulnerability scan identified several items that need to be addressed so you develop a plan to fix them [b]. Your plan identifies the people responsible for fixing the issues, how to do it, and when the remediation will be completed [b]. You also define how to verify that the person responsible has fixed the vulnerability [b]. You document this in an operational plan of action that is updated as milestones are reached [b]. You have a separate resource review the modifications after they have been completed to ensure the plan has been implemented correctly [c]. Potential Assessment Considerations · Is there an action plan to remediate identified weaknesses or deficiencies [a]? · Is the action plan maintained as remediation is performed [b]? · Does the action plan designate remediation dates and milestones for each item [c]?

This Recommendation specifies a message authentication code (MAC) algorithm based on a symmetric key block cipher. This block cipher-based MAC algorithm, called CMAC, may be used to provide assurance of the authenticity and, hence, the integrity of binary data. authentication; block cipher; cryptography; information security; integrity; message authentication code; mode of operation CMAC, like any well-designed MAC algorithm, provides stronger assurance of data integrity than a checksum or an error detecting code. The verification of a checksum or an error detecting code is designed to detect only accidental modifications of the data, while CMAC is designed to detect intentional, unauthorized modifications of the data, as well as accidental modifications.

FedRAMP safeguards and controls are based upon the requirements of NIST SP 800-53 and specify the requirements that must be met for a cloud offering depending on the designation of the information system as a low, moderate, or high FIPS 199 impact level, which then equates to a single FedRAMP impact level. Based on a survey of the FedRAMP Marketplace website, most of the FedRAMP-authorized cloud service providers offer solutions designated as moderate FedRAMP impact level; Therefore, the Government bases the effort and resources needed to implement the requirements of FAR clause 52.239-XX on a cloud FIS designated as a FedRAMP moderate impact level. The safeguards and controls required to meet a FedRAMP moderate impact level include and build upon the NIST SP 800-53 requirements for existing non-cloud FIS systems. As such, the rule uses the costs to implement NIST SP 800-53 for non-cloud FIS as a starting point and then accounts for the additional costs and impacts for contractors to implement approximately 16 additional NIST SP 800-53 controls, which are not required for non-cloud FISs, to be compliant with FedRAMP moderate impact level requirements. Subject matter expects estimate that the effort to implement these 16 additional controls, and those requirements for multifactor authentication, administrative accounts, and consent banners, is approximately 25 percent of the total estimated hours and cost to implement NIST SP 800-53.

Therefore, contractors awarded a contract involving a cloud FIS are anticipated to expend between 2,900 (2,300 hours * 1.25) and 8,200 hours (6,500 hours * 1.25) and \$273,000 (\$218,000 * 1.25) and \$854,000 (\$683,000 * 1.25) in labor and materials in year one to implement, and between \$158,000 (\$127,000 * 1.25) and \$598,000 (478,000 * 1.25) each following year to maintain compliance with NIST SP 800-53 and the contract requirements on multifactor authentication, administrative accounts, and consent banners. Based on the discussion above, the total annual estimated cost for 56 contractors that develop, implement, operate, or maintain a cloud FIS to maintain compliance with FedRAMP requirements, and the requirements specified in the contract as identified above, in year one is approximately \$46 million, and approximately \$32,000,000, each following year to maintain compliance with FedRAMP requirements and the contract, as specified. The cost of the compliance includes the time needed to read and implement NIST SP 800-53 requirements, as well as the additional NIST SP 800-53 controls needed to be compliant with FedRAMP and the contract requirements regarding multifactor authentication, administrative accounts, and consent banners. The following is a summary of the total initial and subsequent year costs to the public as described in section IV.

Requirement	Number of entities impacted	Estimated total cost- first year	Estimated total cost- each subsequent year
Regulatory Familiarization	252	\$183,700	N/A

Computer Security Training & Awareness Course Compendium ## Computer Security Training & Awareness Course Compendium This National Institute of Standards and Technology (NIST) Interagency Report (NISTIR) is a compendium of computer security training and awareness courses. The purpose of this publication is to assist federal agencies locate computer security training resources. This publication is part of a continuing NIST effort to support federal agencies in accordance with NIST's mandate under the Computer Security Act of 1987. In addition to the table of contents, which lists the courses, there are four appendices: A) lists the courses by training areas within audience categories as defined in NIST Special Publication 500-172, Computer Security Training Guidelines; B) lists the vendors that participated in this effort; C) lists the specific products for which training is available; and D) lists the product specific courses.

FAR 4.403-7 requires the contracting officer to insert the clause at FAR 52.204-XX, Controlled Unclassified Information, or the clause at FAR 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information, and to insert the provision at FAR 52.204-WW, Notice of Controlled Unclassified Information Requirements, in solicitations and contracts, excluding solicitations and contracts solely for the acquisition of commercially available off-the-shelf (COTS) items. FAR 4.404 clause prescription is moved to FAR 4.403-7. Coverage from FAR subpart 4.19 has been moved to FAR 4.404. Several organizational changes, including relocation of text and definitions from FAR subpart 4.19, improve the logical flow of information. (printed page 4280) FAR 4.404-1 adds definitions for ·covered contractor information system· and ·covered Federal information·. The term ·Federal contract information· was changed to ·covered Federal information· to align with the term ·covered contractor information system·, and the definition of ·covered Federal information· was revised to clarify that the term excludes CUI and classified information. The definition of ·covered Federal information· is also amended in FAR clause 52.204-21, Basic Safeguarding of Covered Contractor Information Systems. FAR 4.404-2, Applicability, has been added to state that while covered Federal information is not required to be marked or identified by the Government, some administrative markings (e.g., draft, deliberative process, predecisional, not for public release) can indicate that the information is covered Federal information. FAR 4.404-3 has been added to require the contracting officer to insert the clause at FAR 52.204-21, Basic Safeguarding of Covered Contractor Information Systems, in solicitations and contracts, excluding solicitations and contracts solely for the acquisition of COTS items or Federally-funded basic and applied research in science, technology, and engineering at colleges, universities, and laboratories in accordance with National Security Decision Directive 189 when the agency does not provide any covered Federal information to the contractor. FAR 4.404-3 replaces the clause prescription section at FAR 4.1903. The prescription for the clause at FAR 52.204-21 was updated to match the prescription for the CUI clause, because, while both types of information are likely to be in a wide range of contracts, covered Federal information is more ubiquitous than CUI and it may be difficult for the contracting officer to identify during development of the solicitation when covered Federal information may be applicable for the procurement. FAR 4.1301 and 4.1303 have been updated to remove the references to ·PUB Number· and ·PUB· and edit the term ·Federally-controlled information system· to make it ·Federal information system·. (5) FAR 7.103, Agency-head responsibilities. New language is added to describe agency planners' responsibilities for compliance with

Response: Based on DoD decision criteria that include the type and sensitivity of program information to be shared, Program Managers will identify and coordinate as appropriate the CMMC requirement in the solicitation. Internal policies for implementation of CMMC requirements by DoD's acquisition community have been developed, and work will continue as needed to integrate CMMC policies into relevant acquisition policies, guidebooks, and training materials. The DoD intends that requiring activities will determine when compliance should be assessed through CMMC Level 3 as part of the ordinary acquisition planning and requirements generation process. The CMMC assessment level required does not change based on acquisition lifecycle phase, but based on whether FCI and CUI are processed, stored, or transmitted on contractor owned information systems. All contractor-owned information systems that process, store, or transmit CUI are subject to the requirements of NIST SP 800-171 when DFARS clause 252.204-7012 is included in the contract. c. CMMC Level 3 Determination Comment: Multiple comments requested further clarification about which types or categories of CUI require enhanced protection against Advanced Persistent Threats (APTs) at CMMC Level 3 and whether the CMMC level would be based on the Program or the data. Two comments expressed concern or asked how DoD Components will avoid assigning CMMC Level 3 requirements to too many contracts. One comment recommended that DoD modify its criteria for CMMC Level 3 to consider factors such as Acquisition Program Category. Response: CMMC levels do not correspond to CUI levels as the CMMC Program requirements make changes to neither the CUI Program, categories of CUI, nor existing DoD policies for information security requirements. The CMMC Flow down requirement is defined in §.170.23. The Requiring Activity knows the type and sensitivity of information that will be shared with or developed by the awarded contractor and selects the CMMC Level required to protect the information according to DoD guidance. The DoD declines to modify CMMC Level 3 selection criteria as described in the commenters recommended alternatives, which have no bearing on DoD's need for increased confidence in a contractor's ability to safeguard certain CUI against Advanced Persistent Threats. The value of information, and impact of its loss, does not diminish based on the total number or dollar value of contracts held by the awardee, or acquisition program category. The DoD reserves the right to decide when compliance should be assessed by the Government through CMMC Level 3 certification. The DoD defines the work requirements to be solicited for any given program contract. d. Environments Processing Both FCI and CUI Comment:

And FDA agrees: ·AI technologies are transforming health care by producing diagnostic, therapeutic, and prognostic medical recommendations, or decisions, in some cases independently, informed by the vast amount of data generated during the delivery of health care.· [895] In medical devices, areas for AI application include: Image acquisition and processing Early disease detection More accurate diagnosis, prognosis, and risk assessment Identification of new patterns in human physiology and disease progression Development of personalized diagnostics Therapeutic treatment response monitoring [896] For example, clinicians are using AI to distill large volumes of EHR information about a complex patient into a summarized note that they can use to consider diagnoses and treatment. AI also has been used for aid in the detection of diabetic retinopathy, screening for breast and lung cancer, and classification of skin conditions. [897] Others are using ambient AI scribes, a technology that uses microphones to transcribe encounters with patients in real-time. [898] This tool creates clinical documentation that clinicians can later edit, which can lead to improved interactions with patients and reduced time on documentation. [899] Newer AI tools may search medical records for relevant information regarding common conditions and other risk factors [900] or offer relevant questions for clinicians to pose to make an accurate diagnosis. [901] Unfortunately, AI can also be used to harm individuals, both intentionally and unintentionally. Bad actors are using generative AI to threaten the privacy and security of ePHI more effectively through phishing and other social engineering. As explained by NCVHS, ·AI tools can create mass scale [cyberattacks] that are highly effective and major threats to ePHI.· [902] Experts anticipate that AI ·will ultimately pioneer the malicious use of [. . .] ·Offensive AI·highly sophisticated and malicious attack code·[that] will be able to mutate itself as it learns about its environment, and to expertly compromise systems with minimal chance of detection.· [903] Such experts are concerned about the level of destruction that will lie in its wake and compare it to an arms race that can only escalate. [904] Indeed, it seems likely that regulated entities will need to invest in AI to defend against malicious use of AI in the future. [905] After assessing current and potential AI threats, NCVHS recommended that the Department clarify how the HIPAA Rules apply to AI. [906] We agree with their assessment and recommendation. Specifically, ePHI, including ePHI in AI training data, prediction models, and algorithm data that is maintained by a regulated entity for covered functions is protected by the HIPAA Rules and all

applicable standards and specifications. [907] For example, generative AI tools have produced in their output the names and personal information of persons included in the tools' sources of training data. [908]

CMMC provides uniform and improved DoD cybersecurity requirements in three (3) levels, using the security requirements in NIST SP 800-171 and NIST SP 800-172. With this rule, the Department is publishing supplemental guidance documents to assist the public and in particular, small businesses, with CMMC implementation, increasing the likelihood of successful implementation and strengthening cybersecurity across the DIB. CMMC decreases the burden and cost on companies protecting FCI by allowing all companies at Level 1, and a subset of companies at Level 2, to demonstrate compliance through self-assessments. CMMC allows companies, under certain limited circumstances, to make a Plan of Action & Milestones (POA&M) to provide additional time to achieve final certification assessment. These key updates to CMMC benefit the DoD and our national interest by providing: improved safeguarding of competitive advantages through requirements flow-down to the defense contractor supply chain and protections for proprietary information and capabilities, and increased efficiency in the economy and private markets as a result of the streamlining of cybersecurity requirements, the resulting improvements in cybersecurity, and accountability across the supply chain. In summary, the CMMC Program enforces and validates implementation of DoD's required cyber protection standards for companies in the DIB, preserving U.S. technical advantage. In addition, CMMC increases security for the most sensitive unclassified information by applying additional requirements. Implementation of CMMC will help protect DoD's sensitive unclassified information upon which DoD systems and critical infrastructure rely, making it vital to national security. (printed page 89102) CMMC is focused on securing the Department's supply chain, including the smallest, most vulnerable innovative companies. The security risks that result from the significant loss of FCI and CUI, including intellectual property and proprietary data, make implementation of the CMMC Program vital, practical, and in the public interest. III. Regulatory Compliance Analysis A. Executive Order 12866 , ·Regulatory Planning and Review· and Executive Order 13563 , ·Improving Regulation and Regulatory Review· These Executive Orders direct agencies to assess all costs, benefits, and available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health, safety effects, distributive impacts, and equity). These Executive Orders emphasize the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. The Office of Management and Budget (OMB) has determined this proposed rule is significant as defined by Section 3(f)(1) for purposes of Executive Order 12866 . B. Congressional Review Act (5 U.S.C. 801 et seq.) As defined by 5 U.S.C. 804(2)

844. ·While we are proposing in this NPRM in 45 CFR 164.308(a)(13)(i) to specifically include a security incident as an example of an emergency or occurrence that may damage a relevant electronic information system for which a contingency plan would be required, we believe that this is a clarification, rather than a change. Back to Citation 845. · See 45 CFR 164.504(f)(1)(ii) . Back to Citation 846. · See 45 CFR 164.504(f)(1)(iii) . Back to Citation 847. 45 CFR 160.103 (definition of ·Group health plan·). Back to Citation 848. 45 CFR 164.314(b)(2)(i) . Back to Citation 849. 45 CFR 164.504(f)(2)(iii) requires the plan documents to describe an employee or class of employee who receives PHI for payment, health care operations or other matters related to the group health plan; restrict access to PHI and use of PHI by such employees to the plan administration functions that the plan sponsor performs for the group health plan; and provide an effective mechanism for resolving any issues of noncompliance by such persons. Back to Citation 850. 45 CFR 164.314(b)(2)(ii) . Back to Citation 851. 45 CFR 164.314(b)(2)(iii) . Back to Citation 852. 45 CFR 164.314(b)(2)(iv) . Back to Citation 853. 65 FR 82462 , 82508 (Dec. 28, 2000). Back to Citation 854. · See ·2024 Data Breach Investigations Report,· Verizon Business (2024), <https://www.verizon.com/business/resources/reports/dbir/> . Back to Citation 855. 65 FR 82462 , 82508 (Dec. 28, 2000); see also 68 FR 8334 , 8360 (Feb. 20, 2003) (§·164.314(b) provisions are drawn from and intended to support the analogous privacy protections provided for by 45 CFR 164.504(f) and discussed in the 2000 Privacy Rule.). Back to Citation 856. ··Cross-Sector Cybersecurity Performance Goals,· supra note 164. Back to Citation 857. ·Proposed 45 CFR 164.308(a)(2)(i) . Back to Citation 858. ·Proposed 45 CFR 164.308 , 164.310 , 164.312 , and 164.316 . Back to Citation 859. ·The plan sponsor would implement a contingency plan because it is one of the requirements of the administrative safeguards of the Security Rule and would be implemented based on the proposed requirements in 45 CFR 164.314(b)(2)(i) . Back to Citation 860. 45 CFR 164.306(b)(2)(i) . Back to Citation 861. 45

CFR 164.306(b)(2)(ii) . Back to Citation 862. 45 CFR 164.306(b)(2)(iii) . Back to Citation 863. 45 CFR 164.306(b)(2)(iv) . Back to Citation 864. . See Resolution Agreement, Peachstate Health Management, Inc., Office for Civil Rights, U.S. Department of Health and Human Services (Apr. 28, 2021), <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/peachstate/index.html> ; West Georgia Ambulance, Inc., supra note 583; see also 2016-2017 HIPAA Audits Industry Report, supra note 121, p. 27 (the Department found that only 31 percent of regulated entities audited had safeguarded ePHI through risk analysis activities, including developing and implementing policies and procedures). Back to Citation

Some contractors awarded a contract involving a non-cloud FIS will reference NIST SP 800-30 to develop and ensure risk assessment processes and procedures for the system incorporate the requirements of the publication. It is estimated that all 6 contractors awarded a contract involving a non-cloud, custom-build FIS, as well as 4 contractors (20 percent) awarded a contract involving an existing non-cloud FIS will expend approximately 120 hours (3 employees * 8 hours/day * 5 days) reading to become more familiar with and developing or adjusting processes and procedures to comply with NIST SP 800-30 in year one. Using an average loaded wage rate of \$91.10 for FIS occupations, the total estimated labor cost for a contractor to comply with NIST SP 800-30 is approximately \$10,900 (120 hours * \$91.10). ix. NIST SP 800-63-3. Contractors may reference the current version of this guidance for more specific information regarding NIST SP 800-53 controls. As such, the Government assumes that the 28 contractors awarded a contract involving a non-cloud FIS will read and better familiarize themselves with this publication in conjunction with and as a part of their familiarization efforts and costs for NIST SP 800-53. x. NIST SP 800-34. Contractors will reference the current version of this guidance to align its contingency plans for all IT systems to the requirements of NIST SP 800-34. This guidance will be applicable to all contracts involving a custom-build system, as these plans will need to be developed for when a new non-cloud FIS is being designed, as well as some contracts involving existing systems where current plans need to be modified to comply with the guidance. As such, the Government assumes all 6 contractors awarded a contract involving a custom-build, non-cloud FIS and 4 (20 percent * 22) of the contractors awarded a contract involving an existing, non-cloud FIS will expend effort to read and better familiarize themselves with the publication and develop new or adapt existing plans to the guidance of NIST SP 800-34. Some contractors awarded a contract involving a non-cloud FIS will reference this guidance when developing new contingency plans for custom-build FISs and reviewing plans for some existing FISs to ensure the contractor's IT systems meet the requirements set forth in NIST SP 800-34. It is estimated that all 6 contractors awarded a contract involving a non-cloud, custom-build FIS, as well as 4 (20 percent) contractors awarded a contract involving an existing non-cloud FIS will expend approximately 120 hours (3 employees * 8 hours/day * 5 days) reading to become more familiar with and developing or adjusting plans to comply with NIST SP 800-34 in year one. Using an average loaded wage rate of \$91.10 for FIS occupations, the total estimated labor cost for a contractor to comply with NIST SP 800-34 is \$10,900(120 hours * \$91.10). 3. Annual Assessments of the FIS

The Director of Defense Procurement has issued a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to add a requirement for contractor employees that are cleared for access to certain classified information to attest orally that they will comply with the security requirements associated with the information.

Given the failure of regulated entities to implement the security awareness and training standard and consistent with existing guidance, the Department proposes to provide more detailed requirements for security awareness training. Specifically, the Department proposes to rename and redesignate the standard for security awareness and training at 45 CFR 164.308(a)(5)(i) as the standard for security awareness training at proposed 45 CFR 164.308(a)(11)(i) and to add a paragraph heading to clarify the organization of the regulatory text. The proposed standard would require a regulated entity to implement security awareness training for all workforce members on protection of ePHI and information systems as necessary and appropriate for the members of the workforce to carry out their assigned function(s) (i.e., role-based training). The proposals to revise this standard would also align with the Department's essential CPG for Basic Cybersecurity Training because they would require a regulated entity to educate users on how to access ePHI and electronic information systems in a manner that protects the confidentiality, integrity, and availability of ePHI. [584] Additionally, the proposals would align with the essential CPG for Email Security by requiring a regulated entity to train workforce members to guard against, detect, and report suspected or known security incidents, including, but not limited to, malicious software and social engineering. [

585] We propose four implementation specifications for the proposed security awareness training standard. The proposed implementation specification for training at 45 CFR 164.308(a)(11)(ii)(A) would require a regulated entity to establish and implement security awareness training for all workforce members that addresses the following: The written policies and procedures required by the Security Rule, as necessary and appropriate for the workforce members to carry out their assigned functions. [586] Guarding against, detecting, and reporting suspected or known security incidents, including but not limited to malicious software and social engineering. [587] The written policies and procedures for accessing the regulated entity's electronic information systems, including, but not limited to, safeguarding passwords, setting unique passwords of sufficient strength to ensure the confidentiality, integrity, and availability of ePHI, and establishing limitations on sharing passwords. Consistent with the recommendation from NCVHS, such policies and procedures should ensure that the regulated entity does not employ default passwords and should prevent workforce members from sharing of credentials. [588] We do not propose that passwords be required to meet a particular standard because best practices for password configuration may change over time; however, we believe that it is essential for a regulated (printed page 953)

A0195-2a USACIDC, Source Register. (i) Exemption. Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principal function any activity pertaining to the enforcement of criminal laws. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(j) (2) from subsections 5 U.S.C. 552a(c)(3) , (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (e)(4)(H), (e)(4)(I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (c)(4) because an exemption is being claimed for subsection (d), making this subsection not applicable. (C) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (D) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (E) From subsection (e)(2) because in a criminal investigation, the requirement that information be collected to the greatest extent possible from the subject individual would present a serious impediment to law enforcement in that the subject of the investigation would be placed on notice of the existence of the investigation and would therefore be able to avoid detection. (F) From subsection (e)(3) because the requirement that individuals supplying information be provided with a form stating the requirements of subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (G) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from access provisions of subsection (d), making these subsections not applicable. (H) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of (printed page 14753)

Findings from DoD Inspector General report (DODIG-2019-105 ·Audit of Protection of DoD CUI on Contractor-Owned Networks and Systems·) indicate that DoD contractors did not consistently implement mandated system security requirements for safeguarding CUI. That report included recommendations for DoD take steps to assess a contractor's ability to protect this information. The report emphasizes that malicious actors can exploit vulnerabilities in contractors' information systems and exfiltrate information related to some of the Nation's most valuable advanced defense technologies. Due to these shortcomings and the associated risks to national security, the Department developed the Cybersecurity Maturity Model Certification (CMMC) Program to assess contractor and subcontractor implementation of DoD's required cybersecurity standards. The CMMC Program verifies compliance with DoD cyber protection standards by defense contractors and subcontractors and is designed to protect FCI and CUI that is shared by the Department with its contractors and subcontractors, and when developed by a contractor in the course of contract performance but not shared. The program

incorporates a set of cybersecurity requirements into acquisition contracts and provides the Department increased assurance that contractors and subcontractors are meeting these requirements. The CMMC Program has three key features: Tiered Model: CMMC requires that companies demonstrate, through assessment that they have implemented cybersecurity requirements. The type of assessment and requirements against which it is conducted are selected based on the information that must be safeguarded. The program also sets forth the requirements for flow down of CMMC requirements to subcontractors. Assessment Requirement: CMMC assessments allow the Department to verify the implementation of cybersecurity requirements. Implementation through Contracts: Once CMMC is fully implemented, DoD contractors that handle FCI and CUI on their non-Federal information systems will be required to achieve a particular CMMC Status as a condition of contract award. In September 2020, the DoD published the 48 CFR CMMC interim final rule in the Federal Register (DFARS Case 2019-D041) that implemented the DoD's initial vision for the CMMC Program and outlined the key features of the program. The 48 CFR CMMC interim final rule became effective on November 30, 2020. In March 2021, the Department initiated an internal review of CMMC's implementation, informed by more than 750 public comments in response to the 48 CFR CMMC interim final rule. This comprehensive, programmatic assessment engaged cybersecurity and acquisition leaders within DoD to refine policy and program implementation.

3.3.9 Review and Maintain System Security Plans and Applicable Agreements... 3.3.9 Review and Maintain System Security Plans and Applicable Agreements System security plans, applicable agreements (e.

Under the HIPAA Security Rule (45 CFR Part 164, Subpart C) and Privacy Rule (Subpart E), covered entities and business associates must implement safeguards to protect electronic protected health information (ePHI). Key requirements include administrative, physical, and technical safeguards, as well as organizational requirements and documentation. Note: The HIPAA Security Rule NPRM (December 2024) proposes significant changes including mandatory MFA, required encryption, and elimination of the 'addressable' category. These are proposed, not yet finalized. The final rule is expected around May 2026. Organizations should comply with current requirements while preparing for proposed changes.

assessment requirements expanded the scope and cost of the CMMC program. Additionally, some comments described overarching concerns about applicability of CMMC requirements to an ESP when it only provided a Security Protection Asset or processed Security Protection Data. In general, commenters requested to narrow the rule while providing more clarity and definition related to CMMC requirements for ESPs and CSPs. Many comments gave either hypothetical or actual scenarios and asked whether the ESP in that scenario would be required to complete a CMMC assessment at the level required for the OSA being supported. One comment suggested that ESPs should be treated the same as Risk Managed Assets. Another comment suggested that they be treated as Specialized Assets. Two comments proposed that DoD restrict DoD contractors to the use of an ESP/MSP/MSSP that is ISO/IEC 27001:2022(E) certified. Two comments suggest that OSA's be allowed to use non-certified or some form of conditionally certified ESPs if they retain the appropriate artifacts for review. Response: The DoD has revised the rule to reduce the assessment burden on External Service Providers (ESP). ESP assessment, certification, and authorization requirements in §§ 170.19(c)(2) and (d)(2) have been updated. The use of an ESP, its relationship to the OSA, and the services provided need to be documented in the OSA's SSP and described in the ESP's service description and customer responsibility matrix (CRM), which describes the responsibilities of the OSA and ESP with respect to the services provided. ESPs that are CSPs, and process, store, or transmit CUI, must meet the FedRAMP requirements in DFARS clause 252.204-7012. ESPs that are CSPs and do NOT process, store, or transmit CUI, are not required to meet FedRAMP requirements in DFARS clause 252.204-7012. Services provided by the CSP are in the OSA's scope. When ESPs that are not CSPs, process, store, or transmit CUI, a CMMC assessment is required to verify compliance with requirements for safeguarding CUI. Any ESP services used to meet OSA requirements are within the scope of the OSA's CMMC assessment. When ESPs that are not CSPs do NOT process, store, or transmit CUI, they do not require CMMC assessment or certification, however, services they provide are in the OSA's assessment scope. There is nothing in the rule that precludes an ESP, that is not a CSP, from voluntarily requesting a C3PAO assessment. A C3PAO may perform such an assessment if the ESP makes that business decision. ESPs can be part of the same corporate/organizational structure but still be external to the OSA such as a centralized Security Operations Center (SOC) or Network Operations Center (NOC) which supports multiple business units. The same requirements apply and are based on whether the ESP

provides cloud services and whether the ESP processes, stores, or transmits CUI on their systems. An ESP that is used as on-site staff augmentation only, i.e.,

Availability of Guidance and Procedures. The geographic Combatant Commander shall ensure the guidance and procedures prescribed in paragraph (a) of this section are readily available and accessible by PSCs and their personnel (e.g., on a Web page and/or through contract terms), consistent with security considerations and requirements. (c) Subordinate Guidance and Procedures. A sub unified commander or JFC, in consultation with the Chief of Mission, will issue guidance and procedures implementing the standing combatant command publications specified in paragraph (a) of this section, consistent with the situation and operating environment. (d) Consultation and Coordination. The Chief of Mission and the geographic Combatant Commander/sub unified commander or JFC shall make every effort to consult and coordinate responses to common threats and common concerns related to oversight of the conduct of U.S.G.-funded PSCs and their personnel. Dated: August 3, 2011. Patricia L. Toppings, OSD Federal Register Liaison Officer, Department of Defense.

Footnotes 1. ·Nothing in this Final Rule is intended to reflect the views of the DoD or the United States regarding the merits of any claim or defense that may be asserted by a private party in any pending or future litigation or disputes. Back to Citation 1. ·With respect to an area of other significant military operations, the requirements of this part shall apply only upon agreement of the Secretary of Defense and the Secretary of State. Such an agreement of the Secretaries may be made only on an area-by-area basis. With respect to an area of combat operations, the requirements of this part shall always apply. Back to Citation 2. ·Contractors performing private security functions are not authorized to perform inherently governmental functions. In this regard, they are limited to a defensive response to hostile acts or demonstrated hostile intent. Back to Citation 3. ·Available at <http://www.dtic.mil/whs/directives/corres/pdf/302041p.pdf> . Back to Citation 4. ·Published in Title 48 of the Code of Federal Regulations . Back to Citation 5. ·Published in Title 48 of the Code of Federal Regulations . Back to Citation 6. ·Available from <http://www.dtic.mil/whs/directives/corres/pdf/302040p.pdf> . Back to Citation 7. ·Available at <http://www.dtic.mil/whs/directives/corres/html/302041.htm> . Back to Citation 8. ·CJCSI 3121.01B provides guidance on the standing rules of engagement (SROE) and establishes standing rules for the use of force (SRUF) for DOD operations worldwide. This document is classified secret. CJCSI 3121.01B is available via Secure Internet Protocol Router Network at <http://js.smil.mil> . If the requester is not an authorized user of the classified network, the requester should contact Joint Staff J-3 at 703-614-0425. Back to Citation 9. ·Available at <http://www.dtic.mil/whs/directives/corres/html/231101.htm> . Back to Citation 10. ·Available at

From the NIST SP 800-172 Rev 3 Final Public Draft: based on [Assignment: organization-defined circumstances for physical or logical 2063 separation of components]. DISCUSSION System partitioning is part of a defense-in-depth protection strategy. Organizations determine the degree of physical separation of system components. Physical separation options include physically distinct components in separate racks in the same room, critical components in separate rooms, and geographical separation of critical components. Managed interfaces restrict or prohibit network access and information flow among partitioned system components. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY PRA, D

DFARS 252.204-7008 (Compliance with Safeguarding CDI Controls) Requires offerors to represent that they will implement NIST SP 800-171 security requirements. Contractors should review the full text of DFARS 252.204-7008 in conjunction with their contracting officer and legal counsel to ensure full compliance. The clause should be read alongside the CMMC requirements at 32 CFR Part 170.

DoD has updated language in § 170.18(a)(1)(i)(B) to reflect for each DCMA DIBCAC Assessor conducting the assessment, name and government organization information will be required for the CMMC instantiation of eMASS. The DoD has considered the recommendation to change the description of what an SSP should contain and declines to revise the rule text. The NIST SP 800-171 R2 requirement states that an SSP must describe . . . how security requirements are implemented . . . which is equivalent to going . . . through each NIST SP 800-171 security requirement and explain how the requirement is implemented, monitored, and enforced. Perceived Errors DoD declines to make the edit to change ·shall· to ·will· in § 170.9(b). The existing language is consistent with standard

rulemaking usage. The title for NIST SP 800-171A Jun2018 is the current title used by NIST and does not have a version number, so no change was needed. While not used in the rule text, the term enterprise is used in the description of the CMMC Program in the preamble's Statement of Need for This Rule section: Defense contractors can achieve a specific CMMC Level for its entire enterprise network or an enclave(s), depending upon where the information to protected is processed, stored, or transmitted, therefore enterprise remains in the definitions list. DoD verified links by clicking on them in the PDF and by copying and pasting the links into a web browser. In both cases links resolved correctly. The DoD has changed ·all personnel involved in inspection activities· to ·all personnel involved in assessment activities· in §·170.9(b)(9). A comment asserted that there was a rulemaking formatting error in §·170.4(b). DoD is following the Office of the Federal Register standards for this section. In sections or paragraphs containing only definitions, paragraph designations are not used, and the terms are listed in alphabetical order. The definition paragraph begins with the term being defined. If a definition contains subordinate paragraphs, these paragraphs are numbered with paragraph designations beginning with the next appropriate level based on the dedicated definitions section. The 2nd sentence of §·170.17(a)(1) includes the word ·obtaining· for clarity. 35. Comments in Favor of the CMMC Program Comment: Some commenters expressed favorable opinions about the CMMC program as a viable long-term solution to ensure cybersecurity controls are in place. Others commented about specific content of the 32 CFR part 170 CMMC Program proposed rule and the supplemental documents. For example, two commenters specifically complimented the inclusion of an Affirmation requirement and another supported CMMC implementation as a (printed page 83168)

3.3.5 3.3.5
..... -
..... -
..... DevOps ## 3.

Access Control	Maintenance	Security Assessment and Monitoring
Awareness and Training | Media Protection | System and Communications Protection | | Audit and Accountability | Personnel Security | System and Information Integrity | | Configuration Management | Physical Protection | Planning | | Identification and Authentication | Risk Assessment | System and Services Acquisition | | Incident Response | | Supply Chain Risk Management | | Identify the role(s) responsible for security and provide the necessary resources. | Whether it is just one person or multiple people within the business, ensure roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced. Even if cybersecurity activities are outsourced to an external provider, someone within the business should still be designated to manage cybersecurity risk.

s://doi.org/10.6028/NIST.IR.8425 - [4] Fagan M, Megas KN, Watrobski P, Marron J, Cuthill B, Lemire D, Hoehn B, Evans C (2024) Recommended Cybersecurity Requirements for Consumer-Grade Router Products. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Interagency or Internal Report (IR) NIST IR 8425A. <https://doi.org/10.6028/NIST.IR.8425A> - [5] Fagan MJ, Megas KN, Marron JA, Brady KG, Jr., Cuthill BB, Herold R, Lemire D, Hoehn B (2021) IoT Device Cybersecurity Guidance for the Federal Government: IoT Device Cybersecurity Requirement Catalog. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-213A. <https://doi.org/10.6028/NIST.SP.800-213A> - [6] Zhang-Kennedy L and Chiasson S. (2021) "A systematic review of multimedia tools for cybersecurity awareness and education." ACM Computing Surveys (CSUR) 54, no. 1, pp. 139. <https://dl.acm.org/doi/abs/10.1145/3427920> - [7] Plain Writing Act of 2010, Pub. L. No. 111-274, 124 Stat. 2861, 2862 and 2863 (2010) Available at <https://www.govinfo.gov/app/details/PLAW-111publ274> - [8] Balash DG, Ali MM, Kanich C, and Aviv AJ. (2024) " I would not install an app with this label": Privacy Label Impact on Risk Perception and Willingness to Install {iOS} Apps. (USENIX, Berkeley, CA) Twentieth Symposium on Usable Privacy and Security (SOUPS 2024), pp. 413-432. Available at <https://www.usenix.org/system/files/soups2024balash.pdf> - [9] Prange S, Knierim P, Knoll G, Dietz F, De Luca A, and Alt F. (2024) '{I} do (not) need that {Feature!}'-Understanding {Users}' Awareness and Control of Privacy Permissions on Android Smartphones. (USENIX, Berkeley, CA) Twentieth Symposium on Usable Privacy and Security (SOUPS 2024), pp. 453-472. Available at <https://www.usenix.org/system/files/soups2024-prange.pdf> - [10] Chen X, Doublet S, Sergeeva A, Lenzini G, Koenig V, and Distler V.

Voluntary or Mandatory. Include in the Privacy Act Statement specifically whether furnishing the requested personal data is mandatory or voluntary. A requirement to furnish personal data is mandatory ONLY when a federal statute, Executive Order, regulation, or other law specifically imposes a duty on the individual to provide the information sought, and when the individual is subject to a penalty if he or she fails to provide the requested information. If providing the information is only a condition of or prerequisite to granting a benefit or privilege and the individual has the option of receiving the benefit or privilege, providing the information is always voluntary. However, the loss or denial of the privilege, benefit, or entitlement sought must be listed as a consequence of not furnishing the requested information. (7) Some acceptable means of administering the PAS are as follows, in the order of preference: (i) Below the title of the media used to collect the personal information. The PAS should be positioned so that the individual will be advised of the PAS before he or she provides the requested information; (ii) Within the body with a notation of its location below the title; (iii) On the reverse side with a notation of its location below the title; (iv) Attached as a tear-off sheet; or (v) Issued as a separate supplement. (8) An example of a PAS is at appendix B of this part. (9) Include a PAS on a Web site page if it collects information directly from an individual and is retrieved by his or her name or personal identifier (See Office of Management and Budget Privacy Act Guidelines, 40 FR 28949 , 28961 (July 9, 1975)). (10) Army policy prohibits the collection of personally identifying information on public Web sites without the express permission of the user. Requests for exceptions must be forwarded to the Army CIO/G-6. (See AR 25-1, para 6-4n.) (c) Collecting personal information from third parties. (1) It may not be practical to collect personal information directly from the individual in all cases. Some examples of when collection from third parties may be necessary are when: (i) Verifying information; (ii) Opinions or evaluations are needed; (iii) The subject cannot be contacted; or (iv) At the request of the subject individual. (2) When asking third parties to provide information about other individuals, they will be advised of: (i) The purpose of the request; and (ii) Their rights to confidentiality as defined by the Privacy Act of 1974 (Consult with your servicing Staff Judge Advocate for potential limitations to the confidentiality that may be offered pursuant to the Privacy Act). (d) Confidentiality promises. Promises of confidentiality must be prominently annotated in the record to protect from disclosure any information provided in confidence pursuant to 5 U.S.C. 552a(k)(2) , (k)(5), or (k)(7). §505.5 Individual access to personal information. (a) Individual access.

CIS Safeguard 4.10 · Enforce Automatic Device Lockout on Portable End-User Devices Enforce automatic device lockout following a predetermined threshold of local failed authentication attempts on portable end-user devices, where supported. For laptops, do not allow more than 20 failed authentication attempts; for tablets and smartphones, no more than 10 failed authentication attempts. Example implementations include Microsoft? InTune Device Lock and Apple? Configuration Profile maxFailedAttempts. Implementation Groups: 2,3 Asset Type: devices Security Function: respond Parent Control: Secure Configuration of Enterprise Assets and Software

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY DLO ADVERSARY EFFECTS
 NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI
 September 2025 Expose (Detect, Reveal) 1580

Malicious cyber actors have targeted and continue to target defense contractors and the DoD supply chain. These attacks not only focus on the large prime contractors, but also target subcontractors that make up the lower tiers of the DoD supply chain. Many of these subcontractors are small entities that provide critical support and innovation. Overall, the DIB sector consists of over 220,000 companies [26] that process, store, or transmit CUI or FCI in support of the warfighter and contribute towards the research, engineering, development, acquisition, production, delivery, sustainment, and operations of DoD systems, networks, installations, capabilities, and services. The aggregate loss of intellectual property and controlled unclassified information from the DoD supply chain can undercut U.S. technical advantages and innovation, as well as significantly increase the risk to national security. As part of multiple lines of effort focused on the security and resiliency of the DIB, the Department is working with industry to enhance the protection of FCI and CUI within the DoD supply chain. Toward this end, DoD has developed the CMMC Program. Cybersecurity Maturity Model Certification Program The CMMC Program provides a comprehensive and scalable certification approach to verify the implementation of requirements associated with the achievement of a cybersecurity level. CMMC is designed to provide increased assurance to the

Department that defense contractors can adequately protect FCI and CUI at a level commensurate with the risk, accounting for information flow down to its subcontractors in a multi-tier supply chain. Defense contractors can achieve a specific CMMC Status for their entire enterprise network or an enclave(s), depending upon where the information to be protected is processed, stored, or transmitted. The CMMC Program assesses implementation of cybersecurity requirements. The CMMC requirements for safeguarding and security are the same as those required by FAR Subpart 4.19 and DFARS clause 252.204-7012, as well as selected NIST SP 800-172 Feb201 requirements. CMMC Level 1 requires implementation of the safeguarding requirements set forth in FAR clause 52.204-21. CMMC Level 2 requires implementation of the security requirements in NIST SP 800-171 R2. CMMC Level 3 requires implementation of the security requirements in NIST SP 800-171 R2 as well as selected NIST SP 800-172 Feb2021 requirements, with DoD specified parameters. The CMMC security requirements for all three Levels are provided in § 170.14. In general, CMMC assessments do not duplicate efforts from existing DoD assessments. In rare circumstances a re-assessment may be necessary when cybersecurity risks, threats, or awareness have changed.

The 2013 Intellectual Property Commission Report provided concurrence and noted that the ongoing theft represents the greatest transfer of wealth in history. The report also highlighted the challenges of generating an exact figure because Government and private studies tend to understate the impacts due to inadequate data or scope, which is evidenced in subsequent analyses. [55] The responsibility of Federal agencies to protect FCI or CUI does not change when such information is shared with defense contractors. A comparable level of protection is needed when FCI or CUI is processed, stored, or transmitted on contractor information systems. [56] The protection of FCI, CUI, and intellectual property on defense contractor systems can directly impact the ability of the Federal Government to successfully conduct its essential missions and functions. [57] Malicious cyber actors have targeted and continue to target the DIB sector that consists of approximately 220,000 small-to-large sized entities that support the warfighter. In particular, actors ranging from cyber criminals to nation-states continue to attack companies and organizations that comprise the Department's multi-tier supply chain including smaller entities at the lower tiers. From at least January 2020, through February 2022, the Federal Bureau of Investigation (FBI), National Security Agency (NSA), and Cybersecurity and Infrastructure Security Agency (CISA) observed regular targeting of U.S. cleared defense contractors (CDCs) by Russian state-sponsored cyber actors. The actors have targeted sensitive, unclassified information, as well as proprietary and export-controlled technology. The acquired information provides significant insight into U.S. weapons platforms development and deployment timelines, vehicle specifications, and plans for communications infrastructure and IT. By acquiring proprietary internal documents and email (printed page 83193) communications, adversaries may be able to adjust their own military plans and priorities, hasten technological development efforts, inform foreign policymakers of U.S. intentions, and target potential sources for recruitment. [58] In addition to stealing intellectual property for military gains, Russia may conduct cyber-attacks against the U.S. for retaliatory purposes. On March 21, 2022, the Biden-Harris Administration stated intelligence indicates that the Russian Government and Russian-aligned cybercrime groups have threatened to conduct cyber operations in retaliation for perceived cyber offensives against the Russian Government or the Russian people. [59]

Any individual who believes he or she has a legitimate complaint or grievance against the Department of Defense or any DoD employee concerning any right granted by this part shall be permitted to seek relief through appropriate administrative channels. § 310.46 Civil actions. An individual may file a civil suit against a DoD Component if the individual believes his or her rights under the Act have been violated. (See 5 U.S.C. 552a(g) .) § 310.47 Civil remedies. In addition to specific remedial actions, the Privacy Act provides for the payment of damages, court costs, and attorney fees in some cases. § 310.48 Criminal penalties. (a) The Act also provides for criminal penalties. (See 5 U.S.C. 552a(i) .) Any official or employee may be found guilty of a misdemeanor and fined not more than \$5,000 if he or she willfully: (1) Discloses information from a system of records, knowing dissemination is prohibited to anyone not entitled to receive the information (see subpart E of this part); or (2) Maintains a system of records without publishing the required public notice in the Federal Register . (See subpart G of this part.) (b) Any person who knowingly and willfully requests or obtains access to (printed page 18781) any record concerning another individual under false pretenses may be found guilty of misdemeanor and fined up to \$5,000. § 310.49 Litigation status sheet. Whenever a complaint citing the Privacy Act is filed in a U.S. District Court against the Department of Defense, a DoD Component, or any DoD employee, the

responsible system manager shall notify the DPO. The litigation status sheet at Appendix H to this part provides a standard format for this notification. The initial litigation status sheet forwarded shall, as a minimum, provide the information required by items 1 through 6 of the status sheet. A revised litigation status sheet shall be provided at each stage of the litigation. When a court renders a formal opinion or judgment, copies of the judgment and opinion shall be provided to the DPO with the litigation status sheet reporting that judgment or opinion. § 310.50 Lost, stolen, or compromised information. (a) When a loss, theft, or compromise of information occurs (see § 310.14), the breach shall be reported to: (1) The United States Computer Emergency Readiness Team (US CERT) within one hour of discovering that a breach of personally identifiable information has occurred. Components shall establish procedures to ensure that US CERT reporting is accomplished in accordance with the guidance set forth at <http://www.us-cert.gov>. (i) The underlying incident that led to the loss or suspected loss of PII (e.g., computer incident, theft, loss of material, etc.) shall continue to be reported in accordance with established procedures (e.g., to designated Computer Network Defense (CND) Service Providers (reference (z)), law enforcement authorities, the chain of command, etc.). (ii) [Reserved]

Numerous comments requested correction of perceived misstatements, oversights, or erroneous paragraph references in the CAICO responsibilities section. One commenter suggested the level of detail in § 170.10(b) is more appropriate for a statement of work and some paragraphs could be deleted from the rule. They offered preferred rewording to clarify that the CAICO must also comply with AB and ISO/IEC requirements, and further recommended deleting the requirement to provide all documentation in English. In addition, they recommended deleting separation of duties as a requirement, because it is already required under ISO/IEC certification. One commenter conflated CAICO subcontractors with DIB subcontractors and suggested deletion of the rule's restrictions on releasing CMMC-related information. One comment asked whether the Cyber AB and CAICO have documented processes for regular review and updates to their compliance documentation. Lastly, one comment requested duplicative language relating to ethics, record keeping, etc. be moved to a central location in the rule. A few commenters suggested preferred edits to improve the role of the CAICO. One comment noted that the (printed page 83122) accreditor for certifying the CAICO should be a U.S.-based signatory to ILAC or relevant International Accreditation Forum (IAF) in addition to complying with ISO/IEC 17011:2017(E). Two comments noted concerns that having only one CAICO would create an untenable bottleneck should something happen to the single CAICO. One commenter asserted that the CMMC Certified Instructor (CCI) certification requirement is redundant and not cost-effective since instructors will need to be certified as CCPs or CCAs to teach those courses. One comment suggested a grace period of 18-24 months from final rule publication, to allow update of training and examinations, before implementing the CCP and CCA certification requirements. Three comments recommended that Approved Publishing Partner (APP) and Approved Training Providers (ATP) sections be added to Subpart C of the rule. One commenter asked for clarification on what constitutes a CAICO subcontractor and if this includes LTPs and LPPs, and asked why an authorization process for LTPs and LPPs is not included in the rule. One commenter appreciated that CAICO responsibilities include compliance with relevant ISO/IEC standards, as those are internationally recognized standards. One commenter provided an attachment containing an image of an article published in the February 2024 issue of National Defense Magazine. The commentor did not provide specific questions or comments regarding the article, they simply submitted an article. DoD declines to comment on the reposting of information being reported in the media. Response:

3.3.3 Access Control for Network Communications ... 3.3.3 Access Control for Network Communications
A major component of controlling access to network communications and protecting their content is the use of cryptography. 3.3.3.

(B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections

not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further (printed page 14757) necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (24) System identifier and name. A0351-17b USMA, U.S. Military Academy Management System Records. (i) Exemption. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (B) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7) , but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (C) It is imperative that the confidential nature of evaluation and investigatory material on candidates, cadets, and graduates, furnished to the United States Military Academy under a promise of confidentiality be maintained to ensure the candid presentation of information necessary in determinations involving admissions to the Military Academy and suitability for commissioned service and future promotion. (D) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(5) or (k) (7) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) and (k)(7) . (iii) Reasons.

(n) ISO/IEC 17020:2012(E), titled ·Conformity assessment·Requirement for the operation of various types of bodies performing inspection,· Second edition, March 1, 2012 (ISO/IEC 17020:2012(E)), specifies requirements for the competence of bodies performing inspection and for the impartiality and consistency of their inspection activities. It applies to inspection bodies of type A, B or C, as defined in ISO/IEC 17020:2012(E), and it applies to any stage of inspection.· This document is incorporated by reference as a source for requirements on the CMMC Ecosystem. (o) ISO/IEC 17024:2012(E), titled ·Conformity assessment·General requirements for bodies operating certification of persons,· Second edition, July 1, 2012 (ISO/IEC 17024:2012(E)), contains principles and requirements for a body certifying persons against specific requirements and includes the development and maintenance of a certification scheme for persons.· This document is incorporated by reference as a source for requirements on the CMMC Ecosystem. Section 170.3·Applicability Section 170.3 identifies entities to which the rule applies and how the Department intends to implement the rule. The rule applies to defense contractors and subcontractors that will process, store, or transmit FCI or CUI in performance of a DoD contract, and private-sector businesses or other entities that are specified in Subpart C. This rule does not apply to Federal information systems operated by contractors and subcontractors in support of the Government. CMMC Program requirements apply to DoD solicitations and contracts requiring defense contractors and subcontractors to process, store, or transmit FCI or CUI. Exceptions to the applicability of this rule are addressed in § 170.3(c)(1) and (2). Department Program Managers or requiring activities will determine which CMMC Level and assessment type will apply to a contract or procurement. Applicability of the required CMMC Level and assessment type to subcontractors is addressed in § 170.23. Section 170.3 addresses the four-phased implementation plan of the CMMC Program requirements in solicitations and contracts. Phase 1 begins on the effective date of this CMMC 32 CFR part 170 CMMC Program rule or the complementary 48 CFR part 204 CMMC Acquisition rule, whichever occurs later. More information regarding Phase 1 can be found in § 170.3(e)(1). Phase 2 begins one calendar year after the start date of Phase 1. More information regarding Phase 2 can be found in § 170.3(e)(2). Phase 3 begins one calendar year after the start date of Phase 2. More information regarding Phase 3 can be found in § 170.3(e)(3). Phase 4, or full implementation, begins one calendar year after the start date of Phase 3. More information regarding Phase 4 can be found in § 170.3(e)(4). Section 170.4·Acronyms and Definitions

According to the NIST Cybersecurity Framework 2.0, having a comprehensive understanding of the organization's assets (e.g., data, hardware, software, systems, facilities, services, people), suppliers, and related cybersecurity risks enables a regulated entity to prioritize its efforts consistent with its risk management strategy and its mission needs. [453] The proposed standard would be accompanied by three implementation specifications. Under the proposed implementation specification for inventory at proposed 45 CFR 164.308(a)(1)(ii)(A) , the regulated entity would be required to establish a written inventory that contains the regulated entity's technology assets. Technology assets are components of an electronic information system, including

but not limited to hardware, software, electronic media, information, and data. The written inventory would be required to include technology assets that create, receive, maintain, or transmit ePHI and those that do not but that may affect the confidentiality, integrity, or availability of ePHI. [454] It would also be required to include the identification, version, person accountable for, and location of each of the assets or information system components. [455] The proposed implementation specification for network map at proposed 45 CFR 164.308(a)(1)(ii)(B) would require a regulated entity to develop a network map that illustrates the movement of ePHI throughout its electronic information systems, including but not limited to how ePHI enters and exits such information systems, and is accessed from outside of such information systems. Under the proposed implementation specification for maintenance at proposed 45 CFR 164.308(a)(1)(ii)(C) , a regulated entity would be required to review and update the written inventory of technology assets and the network map in the following circumstances: (1) on an ongoing basis, but at least once every 12 months; and (2) when there is a change in the regulated entity's environment or operations that may affect ePHI. Such a change in the (printed page 938)

Architecture, Threat Analysis, and Security Posture Architecture, Threat Analysis, and Security Posture Guo Y, Chandramouli R, Wofford L, Gregg R, Key G, Clark A, Hinton C, Prout A, Reuther A, Adamson R, Warren A, Bangalore P, Deumens E, Farkas C (2024) High-Performance Computing Security: Architecture, Threat Analysis, and Security Posture. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-223. <https://doi.org/10.6028/NIST.SP.800-223>

After a regulated entity conducts a written inventory of its technology assets and creates its network map, it is critical for it to identify the potential risks and vulnerabilities to its ePHI. Conducting a risk analysis is necessary to adequately protect the confidentiality, integrity, and availability of ePHI because it provides the basis for determining the manner in which the regulated entity will comply with and carry out the other standards and implementation specifications in the Security Rule. [460] Basic questions that a regulated entity would consider when conducting a risk analysis that is compliant with the Security Rule include: [461] Have you identified all the ePHI that you create, receive, maintain, or transmit? What are the external sources of ePHI? For example, do vendors or consultants create, receive, maintain, or transmit ePHI? What are the human, natural, and environmental threats to information systems that contain ePHI? (printed page 939) What are the risks posed by legacy devices, including any risks that would be posed by replacing legacy devices with new ones? There are numerous methods of performing a risk analysis, and there is no single method or 'best practice' that guarantees compliance with the Security Rule. [462] The Department has issued multiple guidance documents and tools for regulated entities to help them implement risk analyses, [463] and several versions of its Security Risk Assessment Tool, a desktop application that walks users through the process of conducting a risk assessment. [464] NIST has published numerous guides for risk assessment over the past two decades, [465] in addition to reference materials it has developed in collaboration with the Department, including a toolkit and a crosswalk between the Security Rule to NIST Cybersecurity Framework, [466] and 'how to' guides on risk analysis. [467] In February 2024, NIST released a new guide that provides resources for implementing a Security Rule risk analysis. [468] Consistent with previous Department guidance, the guide describes key elements in a comprehensive risk assessment process, that include the following: Prepare for the assessment by conducting a technology asset inventory. [469] Determine whether ePHI is transmitted to external third parties, such as cloud service providers or others. The regulated entity can also examine how access to ePHI is controlled and whether ePHI is encrypted at rest and in transit. The scope of a risk assessment should include both the physical boundaries of a regulated entity's location and a logical boundary that includes any devices or media that contain ePHI, including electronic networks through which ePHI is transmitted, regardless of its location.

); (2) retail food establishments that employ 10 or fewer full-time equivalent employees; (3) nonprofit food establishments that prepare or serve food directly to the consumer or otherwise provide food or meals for consumption by humans or animals in the United States; and (4) persons who manufacture, process, pack, transport, distribute, receive, hold, or import food contact substances other than the finished container that directly contacts the food. Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food are subject to §§ 1.361 and 1.363 with respect to its packaging (the outer packaging of food that bears the label and does not contact the food). All other persons who manufacture, process, pack, transport, distribute, receive,

hold, or import packaging are excluded from all of the requirements of this subpart J of this final rule. Persons who place food directly in contact with its finished container are subject to all of the requirements of subpart J of this final rule as to the finished container that directly contacts that food. All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that directly contacts the food are excluded from the requirements of subpart J of this final rule as to the finished container, except §§ 1.361 and 1.363. Persons who distribute food directly to consumers are excluded from the requirement in § 1.345 to establish and maintain records to identify the immediate subsequent recipients as to those transactions. The term “consumers” does not include businesses. Persons who operate retail food establishments that distribute food to persons who are not consumers are subject to all of the requirements in subpart J of this final rule. However, the requirements in § 1.345 to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients that are not consumers applies as to those transactions only to the extent the information is reasonably available. Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food for personal consumption are excluded from all of the requirements of subpart J of this final rule. Persons who receive or hold food on behalf of specific individual consumers and who are not also parties to the transaction and who are not in the business of distributing food are excluded from all of the requirements of subpart J of this final rule. The regulations in subpart J of this final rule do not require duplication of existing records if those records contain all of the information required by the subpart. Furthermore, persons can supplement existing records with any new information required by this final rule instead of creating an entirely new record containing both existing and new information.

| Fig. 1. Information security measurement program
structure.....5 | |-----
-----| | Fig. 2. Information security measurement program workflow
.....12 | | Fig. 3. Evaluation and definition
of the existing security program.....13 | | Fig. 4.
Identify and prioritize measures
.....16 | |
Fig. 5. Information security program development and types of
measurement.....18 | | Fig. 6. Information security measures
development process.....19 | | Fig. 7.
Information security measurement
implementation.....20 | 1. Evaluation and
definition of the existing security program 2. Identification and prioritization of measures 3. Data
collection and analysis 4. Identification of corrective actions 5. Application of corrective actions
Evaluation and Definition of the Existing Security Program

The comment included several questions regarding the inputs used to determine lack of ongoing management resource requirements for reaffirmation, a risk management application, and inputs across the DIB regarding the level of assurance needed for affirmations to address liability concerns with the False Claims Act. Another recommendation suggested the DoD clearly state the degree of rigor an OSA should assume and revisit the cost assumptions involved to provide the Entity official with assurance for reaffirmation. One commenter reviewed the CMMC AB's draft CMMC Assessment Process (CAP) document and agreed that 120 hours for a C3PAO's three-person team inclusive of Phases 1, 2 and 3 is appropriate for smaller companies and should be considered a lower bound for C3PAOs deployed resources but suggested the 156 ESP assessment hours should be decreased. One comment highlighted the following rule text, “The total estimated Public (large and small entities) and Government costs associated with this rule, calculated in over a 20-year horizon in 2023 dollars at a 7 percent discount rate and a 3 percent discount rate are provided as follows,” and asked how an organization could become eligible for the 7% discount. One comment proposed DOD remove CMMC Level 1, or defer CMMC Level 1 implementation for several years, since it does not involve CUI. The comment stated CMMC Level 1 cost estimations and burden of compliance in the rule were greatly understated, that few companies subject to this CMMC level have any idea what is expected of them, and most will struggle with financial, technical, and human resources. Though FAR clause 52.204-21 is widely used in Federal contracts, it has not been successfully communicated that NIST SP 800-171A Jun2018 will be used. The comment concludes stating CMMC Level 1 does not include CUI, therefore making cost and compliance an excessive demand. Response: Subsidizing costs for the defense

industrial base compliance is not within the scope of this rule. The rule has taken several steps to keep the cost of compliance with the rule commensurate with the risk to the DoD's information. In addition, Level 1 only requires self-assessment, and many contracts with CUI will only require a Level 2 self-assessment. Companies that are currently and validly attesting that they meet DFARS clause 252.204-7012 should not have difficulty passing a Level 2 self-assessment. Cost estimates provided in this rule were based on internal expertise, compliant with OMB Circular A-4, and informed by public feedback. Certain elements of the estimated costs will be influenced by market forces of supply and demand, which will determine C3PAO pricing for CMMC Level 2 certification assessments.

There is qualified standards acceptance between DCMA DIBCAC High Assessment and CMMC Level 2 Certification Assessment as described in § 170.20(a). There is no standards acceptance between DCMA DIBCAC High Assessment and CMMC Level 3. To be eligible for standards acceptance resulting in a CMMC certification, an OSC must achieve a perfect 110 score on the Joint Surveillance assessment without any open POA&Ms at the time of assessment. If the Joint Surveillance assessment results in POA&M actions, any POA&M must be closed prior to standards acceptance. Completion of a prior DCMA DIBCAC High Assessment does not necessarily indicate the likelihood of a future CMMC Level 3 requirement. DIBCAC High assessments are currently conducted against the NIST SP 800-171 R2 requirements, whereas the DoD will identify the need for a CMMC Level 3 assessment when its internal policies indicate the added protections of NIST SP 800-172 Feb2021 are necessary to adequately safeguard DoD information. Acceptance of a small number of DIBCAC High or Joint Surveillance Program assessments to meet future CMMC Level 2 assessment requirements will reduce the initial demand for C3PAO assessment. Only those DIBCAC High Assessments completed prior to the effective date of the rule are eligible for standards acceptance to meet CMMC Level 2 Certification requirements. The DoD will enter CMMC Level 2 Certifications into eMASS for suitable DIBCAC High Assessments, with a validity period of 3 years from the date of the original High Assessment. A CMMC Final Level 2 certification assessment is entered into eMASS by the C3PAO following a successful (i.e., perfect score with no POA&Ms) joint surveillance assessment against NIST SP 800-171 R2. It is not the result of a CMMC Level 3 assessment but can be provided as evidence that an OSC is ready to initiate a CMMC Level 3 assessment. Although Joint Surveillance is listed as standards acceptance in 170.20(a)(1), the details of this DCMA program and any changes to it are beyond the scope of this rule. A Joint surveillance is a DCMA DIBCAC assessment and falls under their purview. The CMMC office understands that there is disparity between what is assessed by a C3PAO and the DIBCAC and that the guidance information in the DoD Procurement Toolbox is the driving factor. Since the Procurement Toolbox is outside of the scope of the 32 CFR part 170 CMMC Program rule, it cannot be properly addressed here or in the rule. With CMMC the DoD utilizes a risk-based approach in its allowance for POA&Ms, gradient scoring for certain controls (e.g., FIPS and MFA), temporary deficiencies, and enduring exceptions.

The main delays in traceback investigations are long travel times and overnight stays, slow and poor cooperation from recordkeepers, and inconsistent and incomplete records. Many recordkeepers may not be inclined to devote sufficient labor to providing records to inspectors during business hours because that is a costly time of day to reallocate resources. Furthermore, sometimes companies follow time-consuming procedures before approving FDA's request for records access. The legally binding provision in this rule will expedite cooperation from recordkeepers and reduce access times. When we take into account the requirement in the rule that access be provided on weekends, we estimate a substantial amount of time saved due to the records access provision-especially when there are multiple point of service or distributor visits. The inconsistency and incompleteness with which some records are maintained are also important causes for delay in an investigative visit. Records from approximately 50 percent of access requests require additional information from the recordkeeper. Examples of information that may be incomplete include supplier contact information, a description of a product received or shipped, or date of receipt or shipment. This information is used by analysts located at headquarters, along with inventory rotation and control information, to determine precisely what was shipped, by whom, and when it was received. Often, many similar products from different suppliers are received during the course of the day by any given receiver. Frequently, records document transactions from regular suppliers or customers where the identity of the shipper and description of the product can be determined readily based on the regularity and composition of the shipments. Sometimes, an entity will receive an unusual shipment (especially during holiday seasons), or it may receive multiple shipments of similar products from different suppliers, making it difficult to precisely link an incoming product with an outgoing

shipment. Other times, descriptions of products received differ from how they are referenced on the shipping documents, making it difficult for the analyst to link the incoming product with an outgoing shipment. Each category of incidents may result in confusion on the part of the analyst located at central headquarters and require an additional visit by the field inspector to the recordkeeper for further clarification. Because travel times account for a significant amount of time in a traceback investigation, and an estimated 20 percent of all point of service or distributor visits require an overnight stay, we estimated that the final rule would result in substantially reduced traceback durations.

, unless a waiver is granted by the Secretary of Defense, no contract may be awarded to a firm if the government of a country that is a state sponsor of terrorism owns or controls a significant interest in-

(1) The firm; (2) A subsidiary of the firm; or (3) Any other firm that owns or controls the firm. (c) Representation. Unless the Offeror submits with its offer the disclosure required in paragraph (d) of this provision, the Offeror represents, by submission of its offer, that the government of a country that is a state sponsor of terrorism does not own or control a significant interest in-

(1) The Offeror; (2) A subsidiary of the Offeror; or (3) Any other firm that owns or controls the Offeror. (d) Disclosure. (1) The Offeror shall disclose in an attachment to its offer if the government of a country that is a state sponsor of terrorism owns or controls a significant interest in the Offeror; a subsidiary of the Offeror; or any other firm that owns or controls the Offeror. (2) The disclosure shall include-

(i) Identification of each government holding a significant interest; and (ii) A description of the significant interest held by each government. (End of provision) [FR Doc. 2014-28819 Filed 12-10-14; 8:45 am] BILLING CODE 5001-06-P

NCR C Development Toolkit Release 2; NIST-95/1303; 8/1 /96 SCO OpenServer Development System Release 5; NIST-95/1941; The FIPS PUB 128-1 requires the use of application profiles. In particular, FIPS PUB 128-1 requires the use of military specification MIL-D-28003A, commonly known as the Continuous Acquisition and Life-Cycle Support (CALS) CGM Application Profile (AP).

PI-Provisional Instructor PIIIE-Procurement Integrated Enterprise Environment PII-Personally Identifiable Information PLC-Programmable Logic Controller POA&M-Plan of Action and Milestones PRA-Paperwork Reduction Act RM-Risk Management SAM-System of Award Management SC-System and Communications Protection SCADA-Supervisory Control and Data Acquisition SI-System and Information Integrity SIEM-Security Information and Event Management (printed page 83217) SP-Special Publication SPD-Security Protection Data SPRS-Supplier Performance Risk System SSP-System Security Plan (b) Definitions. Unless otherwise noted, these terms and their definitions are for the purposes of this part. Access Control (AC) means the process of granting or denying specific requests to obtain and use information and related information processing services; and/or entry to specific physical facilities (e.g., Federal buildings, military establishments, or border crossing entrances), as defined in FIPS PUB 201-3 Jan2002 (incorporated by reference, see §.170.2). Accreditation means a status pursuant to which a CMMC Assessment and Certification Ecosystem member (person or organization), having met all criteria for the specific role they perform including required ISO/IEC accreditations, may act in that role as set forth in §.170.8 for the Accreditation Body and §.170.9 for C3PAOs. (CMMC-custom term) Accreditation Body is defined in §.170.8 and means the one organization DoD contracts with to be responsible for authorizing and accrediting members of the CMMC Assessment and Certification Ecosystem, as required. The Accreditation Body must be approved by DoD. At any given point in time, there will be only one Accreditation Body for the DoD CMMC Program. (CMMC-custom term) Advanced Persistent Threat (APT) means an adversary that possesses sophisticated levels of expertise and significant resources that allow it to create opportunities to achieve its objectives by using multiple attack vectors (e.g., cyber, physical, and deception). These objectives typically include establishing and extending footholds within the information technology infrastructure of the targeted organizations for purposes of exfiltrating information, undermining or impeding critical aspects of a mission, program, or organization; or positioning itself to carry out these objectives in the future. The advanced persistent threat pursues its objectives repeatedly over an extended period-of-time, adapts to defenders' efforts to resist it, and is determined to maintain the level of interaction needed to execute its objectives, as is defined in NIST SP 800-39 Mar2011 (incorporated by reference, see §.170.2). Affirming Official

Although they were both published in 2003, the interim final rule was published two months after the

Security Rule. Thus, when the Security Rule was published in 2003, it was necessary to specify that the term ‘user’ included both natural persons and entities, but we believe that this is no longer the case because the current definition of ‘person’ includes natural persons as well as entities. [394] b. Proposal The Department proposes to clarify the definition of ‘User’ by removing the reference to an entity. [395] Because the definition of ‘person’ includes an entity, including entity in the definition of ‘user’ is redundant and could cause confusion. We believe that this is a technical correction because it would not change how the Department has interpreted the term. 21. Adding a Definition of ‘Vulnerability’ a. Issues To Address The term ‘vulnerability’ is currently not defined in the Security Rule. The Department previously explained that although some cyberattacks may be sophisticated and exploit previously unknown vulnerabilities (i.e., zero-day attacks), most can be prevented or mitigated by addressing known vulnerabilities. [396] For example, (printed page 930) exploitable vulnerabilities exist across many components of IT infrastructures including, but not limited to, servers, desktops, mobile device operating systems, web software, and firewalls. [397] To mitigate against intrusions and hacking threats, the Department has recommended that regulated entities install vendor patches, make software updates, and monitor sources of cybersecurity alerts describing new vulnerabilities, such as the NIST National Vulnerability Database [398] and CISA’s Known Exploited Vulnerabilities Catalog. [399] b. Proposal The Department proposes to define vulnerability by adopting substantially the same definition as NIST (a ‘weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source’) [400] with minor changes to clarify how it applies to regulated entities and ePHI. The definition, if adopted as proposed, would then form the basis for understanding key assessment and mitigation strategies proposed in this NPRM, such as risk analyses, [401] patch management, [402] and vulnerability management and scans. [403] 22. Clarifying the Definition of ‘Workstation’ a. Current Provision and Issues To Address The Department currently defines the term ‘workstation’ to mean an electronic computing device and provides the examples of technology that dominated the health care environment in 2003 and 2013, such as a laptop, desktop computer, and other device that performs similar functions, and electronic media stored in its immediate environment. [404]

NIST participation has also grown considerably in Internet of Things (IoT) standardization activities, including JTC 1/SC 41 (IoT architecture and vocabulary, IoT Interoperability, and IoT Applications), JTC 1/SC 27 (IoT aspects of Security and Privacy), IETF - SW Updates for IoT, and the International Telecommunications Union-Telecommunication Standardization Sector (ITU-T): Sector Joint Coordination Activity on IoT and ‘IoT and Smart Cities.’ NIST has been instrumental in promoting and participating in the development of a family of voluntary ISO standards that align with NIST’s cryptographic module validation standard and related specifications. NIST serves as the project editor for nine of those standards. FIPS 140-3, Security Requirements for Cryptographic Modules, points to ISO/IEC 19790, Security Requirements for Cryptographic Modules. Testing for these requirements will be performed in accordance with ISO/IEC 24759, Test Requirements for Cryptographic Modules. This is an ongoing effort and will continue over the next several years to support a smooth transition path to those using FIPS 140-3 specifications. - Update of the NIST Risk Management Framework (RMF) . For years, the RMF has been a mainstay for federal agencies and others to use in assessing and managing cybersecurity needs and challenges. Two drafts of the new version were produced in FY18-NIST Special Publication (SP) 800-37, Revision 2 5 before becoming final in early FY19. Updates included significant new guidance in addressing privacy risks and integrating security and privacy into the design of systems. The RMF also references NIST systems security engineering guidance at appropriate points, including NIST SP 800-160, 6 which addresses the engineering of trustworthy secure systems.

Such language is unnecessary in so far as it is already addressed in our existing regulations. Section 862(b)(3) of the 2008 NDAA as amended includes the following language: ‘NONCOMPLIANCE OF PERSONNEL WITH CLAUSE’ The contracting officer for a covered contract may direct the contractor, at its own expense, to remove or replace any personnel performing private security functions in an area of combat operations or other significant military operations who violate or fail to comply with applicable requirements of the clause required by this subsection. If the violation or failure to comply is a gross violation or failure or is repeated, the contract may be terminated for default.’ Incorporation of this statutory language will be considered in the DFARS case implementing Section 862. Comment: The rule fails to address subcontractors providing security for the prime contractor Response: The definition of ‘covered contract’ has been revised in the Rule to cover contracts for the performance of services and/or the delivery of supplies. Further, we will ensure that regulatory

guidance developed subsequent to the publication of this Rule makes clear that subcontractors providing security for prime contractors must comply. Comment: Recommend application of the rule to PSCs working under contract to the DoD whether domestically or internationally. Response: As required by Section 862 of the 2008 NDAA, as amended, this Rule applies to PSCs working for any U.S. Government agency in an area of combat operations or other significant military operations. It also applies to PSCs working for DoD in contingency operations outside the United States. The arrangements for PSC employment in the United States are outside the scope of this Rule. Comment: Section 159.4(a) ·Consistent with the requirement of paragraph (a)(2) * * *. should include at the end of the section, ·Coordination shall encompass the contemplated use of PSC personnel during the planning stages of contingency operations so to allow guidance to be developed under parts (b) and (c) herein and promulgate under 159.5 in a timely manner that is appropriate for the needs of the contingency operation· Response: The language has been revised in the Final Rule. Comment: Section 159.6(a)(i) ·Contain at a minimum procedures to implement the following process * * *. should include, ·That the Secretary of Defense, in coordination with the Secretary of State, shall prescribe regulations on the selection, training, equipping, and conduct of personnel performing private security functions under a covered contract in an area of combat operations· Response: We believe that the current wording is correct, as it reflects our intent.

(Comment 129) Many comments state that because an infrastructure for long-term record retention does not exist to the extent FDA envisions, more reasonable time requirements for retention of records should be established. Another comment states that, although the proposed record retention periods seem simple and straightforward, in practice, they are difficult and confusing for some companies to apply because of the other record retention requirements of varying lengths with which they also must comply. The comment urges FDA to review the recordkeeping retention periods now in effect for specific food categories (e.g., acidified foods, low acid canned foods, bottled water, juices, seafood, and milk) and work to harmonize the proposed record retention requirements with those periods. A few comments question the value of a 2-year record retention period for a product with a shelflife of 60 days, particularly in light of the additional costs associated with the extended retention requirements for perishables. Another comment states that the proposed timeframes for maintaining records for all food products, based solely on whether a food has a shelflife of 7 days, does not appear to utilize sound risk management principles. (Response) FDA agrees in part with these comments and has revised the record retention requirements in the final rule. FDA used similar criteria as the NIST definitions for perishable, semiperishable and long shelf-life food. The record retention requirements in § 1.360(b) of this final rule now require record retention of: (1) 6 months for (printed page 71603) food for which a significant risk of spoilage, loss of value, or loss of palatability occurs within 60 days after the date you receive or release the food; (2) 1 year for food for which a significant risk of spoilage, loss of value, or loss of palatability occurs only after a minimum of 60 days, but within 6 months, after the date you receive or release the food; and (3) 2 years for food for which a significant risk of spoilage, loss of value, or loss of palatability does not occur sooner than 6 months after the date you receive or release the food, including foods preserved by freezing, dehydration, or being placed in a hermetically sealed container. Transporters, or nontransporters retaining records on behalf of a transporter, are required to retain records for 6 months for any food having a significant risk of spoilage, loss of value, or loss of palatability within 60 days after the date the food is received or released and 1 year for any food having a significant risk of spoilage, loss of value, or loss of palatability only after a minimum of 60 days after the date the food is received or released.

MA.L2-3.7.4 · Media Inspection CMMC Assessment Guide · Level 2 | Version 2.13 150 MA.L2-3.7.4 · MEDIA INSPECTION Check media containing diagnostic and test programs for malicious code before the media are used in organizational systems. ASSESSMENT OBJECTIVES [NIST SP 800-171A]132 Determine if: [a] media containing diagnostic and test programs are checked for malicious code before being used in organizational systems that process, store, or transmit CUI. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]132 Examine [SELECT FROM: System maintenance policy; procedures addressing system maintenance tools; system maintenance tools and associated documentation; maintenance records; system security plan; other relevant documents or records]. Interview [SELECT FROM: Personnel with system maintenance responsibilities; personnel with information security responsibilities]. Test [SELECT FROM: Organizational process for inspecting media for malicious code; mechanisms supporting or implementing inspection of media used for maintenance]. DISCUSSION [NIST SP 800-171 REV. 2]133 If, upon inspection of media containing maintenance diagnostic and test programs, organizations determine that the media contain malicious code, the

incident is handled consistent with incident handling policies and procedures. FURTHER DISCUSSION
As part of troubleshooting , a vendor may provide a diagnostic application to install on a system.
As this is executable code , there is a chance that the file is corrupt or infected with malicious
code. Implement procedures to scan any files prior to installation. The same level of scrutiny must
be made as with any file a staff member may download. This requirement, MA.L2-3.7.4, extends both
SI.L2-3.14.2 and SI.L2-3.14.4. SI.L2-3.14.2 and SI.L2-3.14.4 require the implementation and
updating of mechanisms to protect systems 132 NIST SP 800-171A, p. 39. 133 NIST SP 800-171 Rev.
2, p. 28.

The existing implementation specification for isolating health care clearinghouse functions only
applies in the situation where a health care clearinghouse is part of a larger organization. This
would remain true under the proposal to revise this implementation specification, if adopted. In
these situations, the health care clearinghouse is responsible for protecting the ePHI that it is
creating, receiving, maintaining, and transmitting. As discussed in NIST guidance, if a health care
clearinghouse is part of a larger organization, the clearinghouse must implement policies and
procedures that protect the ePHI of the clearinghouse from unauthorized access by the larger
organization. [571] This necessarily includes its relevant electronic information systems.
First, the regulated entity must determine (printed page 951) whether any of its components
constitute a health care clearinghouse under the Security Rule. [572] If no health care
clearinghouse functions exist within the organization, the regulated entity should document this
finding. If a health care clearinghouse does exist within the organization, the regulated entity
must implement procedures that are consistent with the Privacy Rule. [573] Questions for
regulated entities to consider include: If health care clearinghouse functions are performed, are
policies and procedures implemented to protect ePHI from the other functions of the larger
organization? Does the health care clearinghouse share hardware or software with a larger
organization of which it is a part? Does the health care clearinghouse share staff or physical space
with staff from a larger organization? Has a separate network or subsystem been established for the
health care clearinghouse, if reasonable and appropriate? Has staff of the health care clearinghouse
been trained to safeguard ePHI from disclosure to the larger organization, if required for
compliance with the Privacy Rule? [574] Regulated entities should also consider whether
additional technical safeguards are needed to separate ePHI in electronic information systems used
by the health care clearinghouse to protect against unauthorized access by the larger organization.
We also propose to redesignate the implementation specification for access authorization as proposed
45 CFR 164.308(a)(10)(ii)(B) and to modify it to emphasize that a regulated entity must establish
and implement written policies and procedures for granting and revising access to ePHI and the
regulated entity's relevant electronic information systems as necessary and appropriate for each
prospective user and technology asset to carry out their assigned function(s) (i.e., role-based
access policies). Additionally, we propose to redesignate the implementation specification for
access establishment and modification as 45 CFR 164.308(a)(10)(ii)(D)

Strategies for the Integration of Software Supply Chain Security in DevSecOps CI/CD Pipelines ##
Strategies for the Integration of Software Supply Chain Security in DevSecOps CI/CD Pipelines
Chandramouli R, Kautz F, Torres-Arias S (2024) Strategies for the Integration of Software Supply
Chain Security in DevSecOps CI/CD Pipelines. (National Institute of Standards and Technology,
Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-204D.
<https://doi.org/10.6028/NIST.SP.800-204D>

means the designation (such as ·Complete·) used to describe the degree of alarm protection installed
in an alarmed area. Facility means a plant, laboratory, office, college, university, or commercial
structure with associated warehouses, storage areas, utilities, and components, that, when related
by function and location, form an operating entity. FCL means an administrative determination
that, from a security viewpoint, an entity is eligible for access to classified information of a
certain level (and all lower levels) (e.g., a type of favorable entity eligibility determination
used by some CSAs). An entity eligibility determination for the DHS CCIPP is not the equivalent of
an FCL and does not meet the requirements for FCL reciprocity. FGI means information that is: (1)
Provided to the United States by a foreign government or governments, an international organization
of governments, or any element thereof with the expectation, expressed or implied, that the
information, the source of the information, or both, are to be held in confidence; or (2) Produced
by the United States pursuant to, or as a result of, a joint arrangement with a foreign government
or governments, an international organization of governments, or any element thereof, requiring that

the information, the arrangement, or both are to be held in confidence. Foreign interest means any foreign government, agency of a foreign government, or representative of a foreign government; any form of business enterprise or legal entity organized, chartered or incorporated under the laws of any country other than the United States or its territories, and any person who is not a citizen or national of the United States. Foreign national means any person who is not a citizen or national of the United States. Foreign person is defined in 31 CFR 800.224 for CFIUS purposes. FRD means classified information removed from the Restricted Data category upon a joint determination by the DOE and DoD that such information relates primarily to the military utilization of atomic weapons and that such information can be adequately safeguarded as classified defense information. Freight forwarder (transportation agent) means any agent or facility designated to receive, process, and transship U.S. material to foreign recipients. In the context of this rule, it means an agent or facility cleared specifically to perform these functions for the transfer of U.S. classified material to foreign recipients. GCA means an element of an agency that the agency head has designated and delegated broad authority regarding acquisition functions. A foreign government may also be a GCA. Governing board means an entity's board of directors, board of managers, board of trustees, or equivalent governing body. Grant means a legal instrument which, consistent with 31 U.S.C. 6304

In addition, recently FDA was significantly hampered in identifying the source of contaminated food during a trace back investigation following a Hepatitis A outbreak due to contaminated green onions. This outbreak involved a distributor who purchased green onions from a variety of firms in no predictable pattern and distributed them without recording brand and lot information. The distributor did not keep records of the previous sources of the green onions, which might have indicated a particular supplier of green onions during the specified exposure time period. It was impossible for investigators to determine, from the distributor, the identity of the supplier of the green onions that were sent to the implicated restaurant, and therefore FDA had to spend time investigating all potential suppliers of the green onions to identify the one supplier that supplied the restaurant. Speedy trace back would have enabled FDA to prevent further distribution of contaminated products sooner, thereby preventing more illnesses. Further, 20 percent of all tracing investigations are prematurely terminated due to deficiencies in recordkeeping. A reduction of just one premature termination could prevent at least 53 people from becoming ill. Requiring adequate records to complete a tracing investigation reduces trace-back times by 8 days. This increased efficiency facilitates preventive action in 15 to 18 percent of outbreaks. The speed with which a tracing investigation can be conducted is of vital importance in reducing the number of people who could potentially become ill. Access to records that do not exist or that do not contain sufficient information (with no requirement to retain them or make them available in a timely fashion) is not an efficient and effective way to conduct a tracing investigation during a public health emergency involving (printed page 71567) serious adverse health consequences or death to humans or animals. (Comment 3) One comment states that established industry practice with regard to investigating product defects and conducting product recalls is consistent with the terms of the Bioterrorism Act allowing for the rapid identification of the immediate previous source and immediate subsequent recipient of foods. The comment asserts that the industry's response to the events of September 11, 2001, has strengthened these existing practices. The comment explains that as an inevitable result of industry's commitment to Responsible Care Security Code No. 7 and increased requests from customers, emphasis is now shifting from security at fixed plant sites and major distribution centers to security of products throughout the value chain. This shift in emphasis enhances industry's existing traceback capabilities. The comment asserts that the controls needed to effectively trace the source and recipient of foods are already in place.

(Comment 194) Several comments question the format for presenting the additional required information and whether existing records could satisfy the requirements. These comments cite specific types of transactions to illustrate the difficulties in maintaining the required information on one form. In addition, several comments state that the required information is typically available. One comment states that it is already standard business practice to maintain all required information on bills of lading in the trucking industry. Several comments state that FDA should maintain flexibility in the information required, as well as the type of forms maintained. (Response) Neither the proposed nor final rule specifies the form or format in which records are to be established and maintained. There are no restrictions on the kinds of forms maintained. Commercial invoices, bills of lading, packing lists, and other forms commonly used when executing business transactions can all be used to record the information required by the

regulation. We assume that most of the required information is already maintained on forms ordinarily used in conducting business. Persons subject to this final rule can choose to record the required information in one record or to use existing and newly created supplemental records to capture the required information. (Comment 195) One comment requests clarification that transportation record includes the various documents that may be developed by a company and that it is not necessary to include all of this information in one shipping document. Furthermore, the comment asks us to clarify that existing records can be used to satisfy the requirements, even if they are not in the same location within the manufacturing facility (i.e., all required information is there, but not in the same location). Others comment that the proposed regulation is not practical or reasonable, and fails to consider the business practices currently in place for food protection. (Response) FDA believes that most of the information required by this regulation is currently collected as a matter of normal business practices and that any changes to current business practices as a result of this final rule are small. The revised language in the final rule removing the requirement to record lot codes for distributor and retail facilities increases the agency's belief that changes to existing recordkeeping practices will be small. (Comment 196) One comment states that the need for both manufacturers and third party warehouse or wholesalers to keep the records is redundant.

(v) DSS will provide a copy of the DSS FOCI assessment, proposed FOCI action plan and any associated risk assessments to the GCAs with an interest in the company or corporate family. In the absence of written objections (signed at the Program Executive Office (PEO) level or higher) from GCAs with an interest in the company or corporate family, DSS may proceed with implementation of what DSS considers in its discretion to be an acceptable FOCI action plan based on available information. Unless other regulatory review processes for mergers or acquisitions have an earlier suspense date, DSS will provide a 30 calendar day period for the GCAs with an interest in the company or corporate family to provide their PEO level or higher written objections. (vi) DSS will submit to the USD(I) for approval the DSS templates for those FOCI mitigation or negation agreements identified in paragraph (b)(4)(iii) of this (printed page 19475) section as well as templates for any supplements thereto (e.g., the electronic communications plan (ECP) or technology control plan (TCP)). DSS may propose changes to the contents of these template FOCI mitigation or negation agreements. DSS may tailor non-substantive provisions of the template agreement for any particular FOCI case without further approval from the USD(I), provided DSS notifies the OUSD(I) Security Directorate of the deviation from the template. DSS may provide this notification through the electronic submission of an annotated copy of the modified agreement. (5) NID. The requirement for a NID to authorize access to proscribed information applies only to those foreign-owned U.S. contractors or companies in process for an FCL under an SSA which is used as a mechanism for FOCI mitigation. A NID does not authorize disclosure of classified information to a foreign government, a non-U.S. citizen or a non-U.S. entity. Timelines for NID decisions are set forth in 32 CFR part 2004 and the provisions of this paragraph. NIDs can be program, project, or contract specific, subject to the concurrence of NSA for COMSEC, ODNI for SCI or DOE for RD. For program and project NIDs, a separate NID is not required for each contract. DSS will inform the DoD SAPCO of NID requirements to allow the SAPCO to advise of awareness of unacknowledged SAPs or any carve-out SAP activity. (i) A NID is necessary when access to proscribed information is required for: (A) Pre-contract activities in accordance with paragraph (b)(4)(iii)(C)(1) of this section. (B) New contracts to be issued to a company in process for an FCL that DSS has determined to be under FOCI when an SSA is anticipated, or a contractor already cleared under an SSA. (C) Existing contracts when a contractor is acquired by foreign interests and proposes an SSA as the FOCI action plan. (ii) If a contractor is proposing to use an SSA to mitigate FOCI and requires access to proscribed information: (A) DSS will: (1

the incident response team react efficiently during a cyber event and identify the root cause when possible, and the recovery team return the business capabilities in a prioritized and orderly manner. - Authority - Documented name and point of contact information for two or more management staff members who may activate the plan. - Recovery team membership - Point of contact information for designated members of the team who have reviewed, exercised, and are prepared to implement the plan. - Specific recovery details and procedures - Documented system details that apply to the given information system, with diagrams where applicable. These details may prescribe specific recovery activities to be performed by the recovery team, including application restoration details or methods to activate alternate means of processing (e.g., backup servers, failover site). - Out of band communications - Ability to communicate with critical business, IT, and IT security

stakeholders, including external parties like incident response and recovery teams, without using existing production systems, which are frequently monitored by advanced adversaries. - Communication plan - Any specific notification and/or escalation procedures that apply to this information system. As an example, some systems impact users outside of the organization, and legal, public relations, and human resources personnel may need to be engaged to manage expectations and information disclosure about the incident and recovery progress. - Off-site storage details - Details regarding any arrangement for storing specific records or media at an offline or offsite location. This is particularly critical given the credible threat of ransomware that encrypts data and holds the decryption key hostage for payment. - Operational workarounds - Approved workaround procedures if the information system is not able to be restored within the recovery time objective (RTO).

One comment discussed operational energy-related issues including registering activities involved with maintenance and security of the electrical grid, coordinating the activities of other U.S. Government entities operating in the area of operation, and coordinating with the host government on matters related to infrastructure in the area of operation. Response: While the Department appreciates the comment, it does not specifically address private security contractors and does not require a change to the rule. Comment: The second comment was supportive of the rule and suggested the new guidance be made readily available to all contractors. The commenter also opined that these policies should be strictly enforced with increased penalties for those that do not follow the requirements of the rule. Response: The Department appreciates the comment. The new guidance will be made available to the contractors through publication on public websites and will be shared with the contracting community and industry groups to support wider dissemination. Enforcement and penalties are not decided at the Department level. They must be considered and assessed on an individual contract basis. As no public comment required changes to the rule, the Department is finalizing the rule with minor administrative edits to provide additional clarity. Expected Impact of the Final Rule As no public comment was received on the economic analysis of the proposed rule, the Department is finalizing this section with no changes. Separate from this amendment rule, contractors are required to report certain types of incidents to the combatant commander (CCDR) with the geographic area of responsibility (AOR) in which they are assigned and in accordance with orders and instructions established by those commanders. Total Costs for Non-Government and Government The Office of the Secretary of Defense (OSD) subject matter experts on contractors performing private security functions have estimated an average of 4 incidents per month or 48 incidents (responses) per year from 12 respondents. Based on the nature of the task, the subject matter experts determined that it takes approximately 30 minutes for each contractor to retrieve, prepare, and submit the information for each incident report. Based on our assessment, the complexity of the reporting requirement is equivalent to that of a GS-11, step 5. See the rate calculation below. The estimated annual cost to contractors for receiving, preparing, and submitting the information for incidents is as follows: Estimation of Respondent Burden Hours: Office of Management and Budget (OMB) Control Number 0704-0549 Number of respondents 12 Responses per respondent 4 Number of responses (a) 48 Hours per response (b) .5 Estimated hours (number of responses multiplied hours per response) 24 Cost per hour (c) \$45 Total cost to respondents \$1,080

7. Minimize access to data fields necessary to accomplish an employee's task-normally, access shall be granted only to those data elements (fields) required for the employee to perform his or her job rather than granting access to the entire database. 8. Do not totally rely on proprietary software products to protect personnel data during processing or storage. F. Special Procedures 1. Managers shall: a. Prepare and submit for publication all system notices and amendments and alterations thereto. (See § 310.30(f).) b. Identify required controls and individuals authorized access to PII and maintain updates to the access authorizations. c. When required, ensure Privacy Impact Assessments are prepared consistent with the requirements of the DoD Deputy Chief Information Officer Memorandum, 'DoD Privacy Impact Assessment Guidance,' October 28, 2005. d. Train all personnel whose official duties require access to the system of records in the proper safeguarding and use of the information and ensure that they receive Privacy Act training. G. Record Disposal 1. Dispose of records subject to this Regulation so as to prevent compromise. (See § 310.13(c).) Magnetic tapes or other magnetic medium may be cleared by degaussing, overwriting, or erasing. (See DoD Memorandum, 'Disposition of Unclassified DoD Computer Hard Drives,' June 4, 2001.) 2. Do not use respliced waste computer products containing personal data. Appendix B to Part 310 Sample Notification Letter (See § 310.14 of subpart C) Dear Mr. John Miller: On January 1, 2006, a Department of Defense (DoD) laptop computer was stolen from the parked car of a DoD employee in Washington, DC after normal duty hours while the employee was running a personal errand. The laptop

contained personally identifying information on 100 DoD employees who were participating in the xxx Program. The compromised information is the name, social security number, residential address, date of birth, office and home email address, office and home telephone numbers of the Program participants. The theft was immediately reported to local and DoD law enforcement authorities who are now conducting a joint inquiry into the loss. We believe that the laptop was the target of the theft as opposed to any information that the laptop might contain. Because the information in the laptop was password protected and encrypted, we also believe that the probability is low that the information will be acquired and used for an unlawful purpose. However, we cannot say with certainty that this might not occur. We therefore believe that you should consider taking such actions as are possible to protect against the potential that someone might use the information to steal your identity. (printed page 18784) You should be guided by the actions recommended by the Federal Trade Commission at its Web site at http://www.consumer.gov/idtheft/con_steps.htm .

From the NIST SP 800-172 Rev 3 Final Public Draft: Adversary Effects 3134 Cyb er resiliency solutions are only relevant if they have some effect on risk, specifically by reducing the likelihood of the occurrence of threat events,^{21 21} The term ‘threat event’ refers to an event or situation that has the potential to cause undesirable consequences or impacts. Threat events can be caused by adversarial or non-adversarial threat sources. However, this section emphasizes the effect on adversarial threats and specifically on the APT, for which threat events can be identified with adversary activities. the ability of threat events to cause harm, and the extent of that harm.²² 22 While different risk models are valid and useful, three elements are common across most models: (1) the likelihood of occurrence (i.e., the likelihood that a thre

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 i Abstract 1 The protection of Controlled Unclassified Information (CUI) resident in nonfederal systems and organizations is of paramount importance to federal agencies and can directly impact the ability of the Federal Government to successfully conduct its essential missions and functions. This publication provides federal agencies with recommended security requirements for protecting the confidentiality, integrity, and availability of CUI when it is resident in a nonfederal system and organization and associated with a critical program or high value asset (HVA). The security requirements apply to the components of nonfederal systems that process, store, or transmit C

HIPAA Security Rule section 164.314 (Organizational Requirements) addresses group health plan requirements. Covered entities and business associates must implement appropriate safeguards to protect electronic protected health information (ePHI). For group health plan requirements, organizations should: 1. Establish and document policies specific to group health plan requirements 2. Implement technical and procedural controls 3. Train workforce members on their responsibilities 4. Conduct periodic risk assessments addressing group health plan requirements 5. Maintain documentation of compliance efforts Under 45 CFR 164.314, this is a organizational requirements requirement that applies to all covered entities and business associates that create, receive, maintain, or transmit ePHI.

(c) The failure of any person to make records or other information available to FDA as required by section 414 or 704(a) of the act and this regulation is a prohibited act under section 301 of the act. Compliance Dates §.1.368 What are the compliance dates for this subpart? The compliance date for the requirements in this subpart is December 9, 2005. However, the compliance dates for small and very small businesses are contained in paragraphs (a) and (b) of this section. The size of the business is determined using the total number of full-time equivalent employees in the entire business, not each individual location or establishment. A full-time employee counts as one full-time equivalent employee. Two part-time employees, each working half time, count as one full-time equivalent employee. (a) The compliance date for the requirements in this subpart is June 9, 2004, for small businesses employing fewer than 500, but more than 10 full-time equivalent employees. (b) The compliance date for the requirements in this subpart is December 11, 2006, for very small businesses that employ 10 or fewer full-time equivalent employees. PART 11-ELECTRONIC RECORDS; ELECTRONIC SIGNATURES 3. The authority citation for 21 CFR part 11 continues to read as follows: Authority: 21 U.S.C. 321-393 ; 42 U.S.C. 262 . 4. Section 11.1 is amended by adding paragraph (f) to read as follows: §.11.1 Scope * * * * * (f) This part does not apply to records required to be established or maintained by §§.1.326 through 1.368 of this chapter. Records that satisfy the requirements of part 1, subpart J of this chapter, but that also are required under

other applicable statutory provisions or regulations, remain subject to this part. Dated: November 30, 2004. Lester M. Crawford, Acting Commissioner of Food and Drugs. Dated: December 2, 2004. Tommy G. Thompson, Secretary of Health and Human Services. Footnotes 1. FDA's long-standing interpretation of the FD&C Act's definition of color additive, section 201(t), is an additional example of where "food" is used more narrowly than as defined in section 201(f) of the FD&C Act. A color additive is defined in section 201(t) as a substance that "when applied to a food is capable of imparting color thereto * * *". The agency's food additive regulations distinguish between color additives and "colorants," the latter being used to impart color to a food contact material (21 CFR 178.3297(a)). See also 21 CFR 70.3(f) . Thus, "food" as it appears in the statutory definition of color additive, necessarily excludes food contact materials. Back to Citation [FR Doc. 04-26929 Filed 12-6-04; 8:45 am] BILLING CODE 4160-01-S

Breach Notification Rule's safe-harbor provision. [724] As the use of mobile computing devices (e.g., laptops, smartphones, tablets) has become more pervasive, the risks to sensitive data stored on such devices also have increased. [725] And while in 2003 and even in 2013, encryption might have been out of reach for many regulated entities because of cost or a similar reason, [726] today, encryption solutions are generally considered to be widely accessible. The cost of such solutions has decreased significantly, as has the difficulty in implementing such solutions. In fact, many applications have encryption solutions embedded in them. [727] Once enabled, a device's encryption solution can protect stored sensitive data, including ePHI, from unauthorized access in the event the device is lost or stolen. The same is true for most software today. [728] Thus, while encryption of a particular regulated entity's ePHI might not have been reasonable and appropriate in 2003 or 2013, the Department believes encryption generally is reasonable and appropriate today. [729] Because the prevalence of encryption solutions has increased, as has their affordability and the role they play in protecting information, including ePHI, the Department believes it is appropriate to consider requiring encryption and elevating it from an implementation specification to a standard to increase its visibility and prominence. Based on this and consistent with NCVHS' recommendation, the Department proposes to redesignate the implementation specification for encryption and decryption at 45 CFR 164.312(a)(2)(iv) as a standard at proposed 45 CFR 164.312(b)(1) . [730] The proposed standard would incorporate the requirements of two implementation specifications that address encryption—the one addressed here and the one at 45 CFR 164.312(e)(2)(ii) . [731] The Department proposes that the new standard would require a regulated entity to configure and implement technical controls to encrypt and decrypt all ePHI in a manner that is consistent with prevailing cryptographic standards. This proposed new standard aligns with the Department's essential CPG for Strong Encryption by calling for regulated entities to deploy encryption to protect ePHI and with the recommendation of NCVHS. [732] We also note that the adoption of health IT that is certified through the ONC Health IT Certification Program as having the technical capability to encrypt and decrypt electronic health information, using an encryption algorithm that meets certain requirements, may contribute to a regulated entity's compliance with the proposed standard for encryption and decryption, should the proposal be finalized. [733]

From the NIST SP 800-172 Rev 3 Final Public Draft: ODPs provide flexibility through the use of assignment and selection operations to allow federal agencies and nonfederal organizations to specify values for the designated parameters in the requirements. 15 NIST does not establish or assign values for ODPs. If ODP values for selected security requirements are not formally established or assigned by a federal agency or a consortium of federal agencies, nonfederal organizations must assign those values to complete the requirements. Assignment and selection operations provide the capability to customize the enhanced security requirements based on specific protection needs. The determination of ODP NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 values can be guided and info

115. See "Frequently Asked Question: Health Information Exchange: The Benefits," The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, <https://www.healthit.gov/faq/why-health-information-exchange-important> . Back to Citation 116. See Genevieve P. Kanter, et al., "Beyond Security Patches: Fundamental Incentive Problems in Health Care Cybersecurity," JAMA Health Forum, Volume 2, Issue 10, p. e212969 (Oct. 8, 2021), <https://jamanetwork.com/journals/jama-health-forum/fullarticle/2784981> ; Chon Abraham, et al., "Muddling through cybersecurity: Insights from the U.S. healthcare industry," Business Horizons, Volume 62, Issue 4, p. 539-548, p. 539 (July-Aug. 2019),

<https://www.sciencedirect.com/science/article/abs/pii/S0007681319300436> ; Eric Perakslis, ·Responding to the Escalating Cybersecurity Threat to Health Care,· The New England Journal of Medicine, Volume 387, Issue 9 (Sept. 1, 2022), <https://www.nejm.org/doi/abs/10.1056/NEJMp2205144> ; Anthony James Cartwright, ·The elephant in the room: cybersecurity in healthcare,· Journal of Clinical Monitoring and Computing, Volume 37, Issue 5, p. 1123-1132 (Apr. 24, 2023), <https://link.springer.com/article/10.1007/s10877-023-01013-5> . Back to Citation 117.

·Report on Improving Cybersecurity In The Health Care Industry,· Health Care Industry Cybersecurity Task Force, p. 1 (June 2017), <https://www.phe.gov/preparedness/planning/cybertf/documents/report2017.pdf> . Back to Citation 118.

·The NIST Cybersecurity Framework (CSF) 2.0,· supra note 15. Back to Citation 119.

·Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients,· supra note 16. Back to Citation 120.

·Cybersecurity Performance Goals,· supra note 18. Back to Citation 121.

· See ·2016-2017 HIPAA Audits Industry Report,· Office for Civil Rights, U.S. Department of Health and Human Services (Dec. 2020), <https://www.hhs.gov/sites/default/files/hipaa-audits-industry-report.pdf> . Back to Citation 122.

· See sec. 262 of Public Law 104-191 , 110 Stat. 2023 (Aug. 21, 1996) (codified at 42 U.S.C. 1320d-1(f)), added sec. 1172(f) of the SSA; see also ·About NCVHS,· National Committee on Vital and Health Statistics, www.ncvhs.hhs.gov . Back to Citation 123.

· See Letter from NCVHS Chair Jacki Monson to HHS Secretary Xavier Becerra (May 10, 2022), <https://ncvhs.hhs.gov/wp-content/uploads/2022/05/NCVHS-Recommendations-to-Strengthen-Cybersecurity-in-HC-05-10-2022-508.pdf> ; see also Letter from NCVHS Chair Jacki Monson to HHS Secretary Xavier Becerra (Nov. 29, 2023), https://ncvhs.hhs.gov/wp-content/uploads/2024/01/Letter-to-the-Secretary-Recommendations-to-Strengthen-the-HIPAA-Security-Rule_508.pdf . Back to Citation 124.

42 U.S.C. 1320d-1(f) . Back to Citation 125.

·Subtitle F of title II of HIPAA, Public Law 104-191 , 110 Stat. 1936 (Aug. 21, 1996). Back to Citation 126.

·Sec. 261 of Public Law 104-191

One comment suggested that C3PAOs be permitted to conduct partial assessments of ESPs, MSPs, and MSSPs. Multiple comments expressed concern with CMMC assessment requirements for OSAs that use ESPs, stating that OSAs would be unlikely to know which components of the services they purchased were covered by a required CMMC Level 2 assessment. This commenter recommended the creation of a separate type of CMMC assessment specifically for ESPs, which they further recommended should be highlighted on the CMMC AB marketplace to assist OSAs in selecting an appropriately vetted ESP. These comments provided an extended description of the specific scoping guidance that should be adding to existing CMMC supplemental documentation, as well as several sample scenarios explaining how requirements for this new type of assessment should be applied. Two comments highlighted that the rule's preamble does not include details of assessment and implementation requirements. Several commenters recommended the DoD abandon the CMMC ecosystem model and conduct all cybersecurity compliance assessments using DIBCAC assessors, which would reduce cost to the DIB. One such commenter suggested that DIBCAC assessment of C3PAOs, as part of the accreditation process, detracts from DIBCAC's capacity to perform CMMC level 2 assessments for the DIB. Another noted that as Government employees, DIBCAC assessors could exercise judgement to make risk-tolerance decisions that non-Government C3PAOs cannot, including possible acceptance of partial non-compliance. Response: DoD must enforce CMMC requirements uniformly across the Defense Industrial Base for all contractors and subcontractors who process, store, or transmit CUI. The value of information and impact of its loss does not diminish when the information moves to contractors and subcontractors. The DoD has considered the recommendation and declines to revise the rule text to rely solely on self-assessment or eliminate the 3-year validity period to rely on a one-time certification. It is important that contractors maintain security compliance for systems that process, store, or transmit DoD CUI. Given the evolving cybersecurity threat, DoD's best interests are served by ensuring that CMMC Level 2 assessments remain valid for no longer than a 3-year period, regardless of who performs the assessment.

16. ·Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients,· U.S. Department of Health and Human Services and the Healthcare & Public Health Sector Coordinating Council (2023), <https://405d.hhs.gov/Documents/HICP-Main-508.pdf> . Back to Citation 17.

·Start with Security: A Guide for Business,· Federal Trade Commission (Aug. 2023), https://www.ftc.gov/system/files/ftc_gov/pdf/920a_start_with_security_en_aug2023_508_final_0.pdf . Back to Citation 18.

·Cybersecurity Performance Goals,· U.S. Department of Health and Human

Services (Jan. 2024), <https://hphcyber.hhs.gov/performance-goals.html> . Back to Citation 19. ·Sec. 1174(b)(1) of the SSA; 45 CFR 160.104 . Back to Citation 20. · See sec. 261 of Public Law 104-191 , 110 Stat. 1936 (codified at 42 U.S.C. 1320d note). Back to Citation 21. · See ·A Guide to the Rulemaking Process,· Office of the Federal Register (2011), p. 8, https://www.federalregister.gov/uploads/2011/01/the_rulemaking_process.pdf . Back to Citation 22. · See 78 FR 5566 , 5569 (Jan. 25, 2013). Back to Citation 23. · See 42 U.S.C. 1320d-4(b)(2) . Back to Citation 24. 45 CFR 164.306(d)(3)(i) and (d)(3)(ii)(A) . Back to Citation 25. 45 CFR 164.306(d)(3)(ii)(B) . Back to Citation 26. · See 45 CFR 160.104(c)(1) , which requires the Secretary to provide at least a 180-day period for regulated entities to comply with modifications to standards and implementation specifications in the HIPAA Rules. Back to Citation 27. 45 CFR 164.314(a)(1) . Back to Citation 28. Public Law 104-191 , 110 Stat. 1936 (Aug. 21, 1996) (codified at 42 U.S.C. 201 note). Back to Citation 29. · See H.R. Rep. No. 104-496, at 66-67 (1996). Back to Citation 30. Public Law 104-191 , 110 Stat. 1936 (Aug. 21, 1996). Back to Citation 31. ·Sec. 262(a) of Public Law 104-191 , 110 Stat. 2021 (Aug. 21, 1996) (codified at 42 U.S.C. 1320d). Back to Citation 32. ·Sec. 261 of Public Law 104-191 , 110 Stat. 2021 (Aug. 21, 1996), as amended by sec. 1104(a) of Public Law 111-148 , 124 Stat. 146 (Mar. 23, 2010) (codified at 42 U.S.C. 1320d note). Back to Citation 33. ·On a resolution waiving points of order against the Conference Report to H.R. 3103, members debated an ·erosion of privacy· balanced against the administrative simplification provisions. Thus, from HIPAA's inception, privacy has been a central concern to be addressed as legislative changes eased disclosures of PHI. See 142 Cong. Rec. H9777 and H9780. Back to Citation 34. ·142 Cong. Rec. S9515-16 (daily ed. Aug. 2, 1996) (statement of Sen. Simon). Back to Citation 35. · See H.R. Rep. No. 104-496 Part 1, at 99-100 (Mar. 25, 1996). Back to Citation 36. · See sec. 262(a) of Public Law 104-191 , 110 Stat. 2021, adding section 1172 to the SSA (codified at 42 U.S.C. 1320d-1); see also section 13404 of the American Recovery and Reinvestment Act (ARRA) of 2009, Public Law 111-5 , 123 Stat. 115 (Feb. 17, 2009) (codified at 42 U.S.C. 17934

Amend section 53.204-1 by revising the introductory text to read as follows: 53.204-1 Safeguarding classified information within industry (DD Form 254, DD Form 441). The following forms, which are prescribed by the Department of Defense, shall be used by DoD components and those nondefense agencies with which DoD has agreements to provide industrial security services for the National Industrial Security Program if contractor access to classified information is required, as specified in subpart 4.4 and the clause at 52.204-2: * * * * 53.300 [Amended] 12. In section 53.300 amend the table in paragraph (b) in the table 53-2 by removing from Form DD 254 url, <http://www.dtic.mil/whs/directives/forms/eforms/dd0254.pdf> and adding <https://www.esd.whs.mil/Portals/54/Documents/DD/forms/dd/dd0254.pdf> ; and removing from Form DD 441 url, http://www.dtic.mil/whs/directives/forms/eforms/dd0441_2017.pdf and adding https://www.esd.whs.mil/Portals/54/Documents/DD/forms/dd/dd0441_2020.pdf in their places, respectively. [FR Doc. 2020-12762 Filed 7-1-20; 8:45 am] BILLING CODE 6820-EP-P

Persons seeking unauthorized access to data and information are increasingly sophisticated. Their methods of attempting to gain such access can take many forms and result in a wide array of harms, as discussed above. One of the methods they use is through the introduction of malicious software (also referred to as malware) into an electronic information system. As the sophistication of bad actors has increased, so has the variety of types of malicious software that they use to access electronic information systems. The Security Rule defines malicious software but limits it to software designed to damage or disrupt a system. The regulatory text provides only one example of malicious software in regulatory text: a virus. b. Proposal The Department proposes to replace the current definition of malicious software with one that would be consistent with how cybersecurity experts define the term today. [362] Specifically, we propose to define it to mean software or firmware intended to perform an unauthorized action or activity that will have adverse impact on an electronic information system and/or the confidentiality, integrity, or availability of electronic protected health information. This proposal would therefore clarify that malicious software could include either software or firmware and that the negative effects of the malicious software may not be limited to damaging or disrupting a system. Rather, effects of the software could be intended to have any type of adverse impact on an electronic information system and/or the confidentiality, integrity, or availability of ePHI. The Department also proposes to include in regulatory text a non-exhaustive list of examples, such as viruses, worms, Trojan horses, spyware, and some forms of adware, to assist regulated entities in understanding what constitutes malicious software. (printed page 926) 10. Adding a Definition of ·Multi-Factor Authentication· (MFA) a. Issues To

Address The Security Rule includes several technical safeguard provisions that require regulated entities to identify and authenticate persons accessing information and systems to protect ePHI. Section 164.312(a)(2)(1) includes the standard that requires a regulated entity to implement technical policies and procedures that limit access to ePHI to only those persons or software programs that have been granted access rights, while 45 CFR 164.312(d)(2), the standard for person or entity authentication, requires a regulated entity to implement procedures to verify that a person seeking access to ePHI is the one claimed.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [Docket DARS-2020-0038; OMB Control No. 0750-0004] AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Notice and request for comments regarding a proposed extension of an approved information collection requirement. SUMMARY: In compliance with the Paperwork Reduction Act of 1995, DoD announces the proposed extension of a public information collection requirement and seeks public comment on the provisions thereof. DoD invites comments on: whether the proposed collection of information is necessary for the proper performance of the functions of DoD, including whether the information will have practical utility; the accuracy of the estimate of the burden of the proposed information collection; ways to enhance the quality, utility, and clarity of the information to be collected; and ways to minimize the burden of the information collection on respondents, including the use of automated collection techniques or other forms of information technology. The Office of Management and Budget (OMB) has approved this information collection for use through April 30, 2021. DoD proposes that OMB extend its approval for use for three additional (printed page 70593) years beyond the current expiration date. DATES: Consideration will be given to all comments received by January 4, 2021. ADDRESSES: You may submit comments, identified by OMB Control Number 0750-0004, using any of the following methods: Federal eRulemaking Portal: <http://www.regulations.gov>. Follow the instructions for submitting comments. Email: osd.dfars@mail.mil. Include OMB Control Number 0750-0004 in the subject line of the message. Mail: Defense Acquisition Regulations System, Attn: Ms. Heather Kitchens, OUSD(A&S)DPC(DARS), 3060 Defense Pentagon, Room 3B938, Washington, DC 20301-3060. Comments received generally will be posted without change to <http://www.regulations.gov>, including any personal information provided. FOR FURTHER INFORMATION CONTACT: Ms. Heather Kitchens, telephone 571-372-6104. SUPPLEMENTARY INFORMATION: Title and OMB Number: Defense Federal Acquisition Regulation Supplement (DFARS), Assessing Contractor Implementation of Cybersecurity Requirements; OMB Control Number 0750-0004. Affected Public: Businesses and other for-profit entities. Respondent's Obligation: Required to obtain or retain benefits. Type of Request: Extension of a currently approved collection. Reporting Frequency: On occasion.

, a regulated entity would be required to deploy technology assets and/or technical controls that protect all of the technology assets in its relevant electronic information systems against malicious software, such as viruses and ransomware. Anti-malware software, especially when used in combination with other technical controls such as intrusion detection/prevention solutions, can also help prevent, detect, and contain cyberattacks. [751] This protection would be applied to all of a regulated entity's technology assets in its relevant electronic information systems. When determining how to fulfill this proposed obligation, regulated entities may consider deploying tools such as anti-malware and endpoint detection and response (EDR) solutions. Anti-malware tools generally scan a regulated entity's electronic information systems to (printed page 972) identify malicious software. [752] Such tools may also quarantine malicious software if identified. As explained by the Office of Management and Budget, "EDR combines real-time continuous monitoring and collection of endpoint data [. . .] with rules-based automated response and analysis capabilities." [753] We propose a new implementation specification for software removal at proposed 45 CFR 164.312(c)(2)(ii) to require a regulated entity to remove extraneous software from the regulated entity's relevant electronic information systems. Software is extraneous if it is unnecessary for the regulated entity's operations. It can be a target for attack, and older applications may no longer be supported with patches for new vulnerabilities. [754] Removal of unnecessary software reduces an avenue of attack. The Department is not proposing to specify what would constitute necessary and unnecessary software. Rather, we intend that the regulated entity

would consider removal of unwanted or unused software, for example, default software added by a computer manufacturer or reseller where such software may open an avenue for unnecessary risk because the regulated entity does not intend to use it. Accordingly, the proposal would require a regulated entity to consider all software on its relevant electronic information systems and any potential avenue of risk and address the risk through software removal where such software is unnecessary for the regulated entity's operations. The proposed implementation specification for configuration at proposed 45 CFR 164.312(c)(2)(iii) would require a regulated entity to configure and secure operating systems and software in a manner consistent with the regulated entity's risk analysis. Generally, a regulated entity's risk analysis should guide its implementation of appropriate technical controls to reduce the risk to ePHI. [755] Requiring operating systems and software to be maintained in a secure manner would reduce exploitable vulnerabilities. [756] Often, known vulnerabilities can be mitigated by applying vendor patches or upgrading to a newer version. [757]

), encourages the voluntary formation of organizations engaged in the sharing of information related to cybersecurity risks and incidents to establish mechanisms to continually improve their capabilities and functions as well as to better allow them to partner with the Federal government on a voluntary basis. E.O. 12333 ; ·United States Intelligence Activities,· December 4, 1981, as amended (available at <https://www.archives.gov/federal-register/codification/executive-order/12333.html> , provides general principles that in addition to and consistent with applicable laws are intended to achieve the proper balance between the acquisition of essential information and the protection of individual interests. Title 42 U.S.C. 2011 et seq. (also known as and referred to in this rule as ·The Atomic Energy Act of 1954,· as amended (AEA)); Title 50 U.S.C. chapter 44 (also known as ·The National Security Act of 1947, as amended); Title 50 U.S.C. 3501 et seq. (also known as ·The Central Intelligence Agency Act of 1949,· as amended); Public Law 108-458 (also known as the ·Intelligence Reform and Terrorism Prevention Act of 2004·), which includes development of uniform and consistent policies and procedures to ensure effective, efficient and timely completion of security clearances. Finally, 32 CFR part 2004 ·National Industrial Security Program,· May 7, 2018, establishes uniform standards for the NISP, and helps agencies implement requirements in E.O. 12829 , and establishes agency responsibilities for implementing the insider threat provisions of E.O. 13587 . III. Changes Made by This Rule and Expected Impact The NISPOM was first published in 1995 as DoD Manual 5220.22. Updates to the NISPOM have included Conforming Change 1, March 28, 2013 and NISPOM Change 2 in May 21, 2016. The most current version of the NISPOM (Change 2) is available at <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodm/522022M.pdf?ver=2019-06-06-145530-170> . In addition to codifying the NISPOM in the CFR and adding the requirements of SEAD 3 and Section 842 of Public Law 115-232 , DoD is also removing 32 CFR part 117, subpart C , ·National Industrial Security Program· because it is duplicative of 32 CFR part 2004 , ·National Industrial Security Program· and removing 32 CFR part 117, subpart B , because it is also duplicative of other industrial security provisions set forth in 32 CFR part 2004 . These administrative removals support a recommendation from the DoD Regulatory Reform Task Force created under E.O. 13777 , Enforcing the Regulatory Reform Agenda (available at <https://www.govinfo.gov/content/pkg/FR-2017-03-01/pdf/2017-04107.pdf>), and by themselves create no changes in current DoD policy. Upon the effective date of 32 CFR part 117 , DoD will no longer publish the DoD Manual 5220.22, NISPOM as a DoD policy issuance. Specific changes in this rule that are not in the current NISPOM, include the following. §.117.8: Reporting Requirements. §.117.8(a) General

CIS Safeguard 5.4 · Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account. Implementation Groups: 1,2,3 Asset Type: users Security Function: protect Parent Control: Account Management

Where an exception at paragraph (a)(4)(ii)(D) of this section applies, a covered entity or business associate must document in real-time the existence of an applicable exception and implement reasonable and appropriate compensating controls in accordance with paragraph (a)(4)(ii)(F) of this section. (F) Compensating controls. To the extent that a covered entity or business associate determines that an exception at paragraph (a)(4)(ii)(D) of this section applies, a covered entity or business associate must implement reasonable and appropriate security measures to address the identified risk in a timely manner as required by paragraph (a)(5)(ii)(D) of this section until a

patch, update, or upgrade that does not adversely affect the confidentiality, integrity, or availability of electronic protected health information becomes available. (5) Standard: Risk management ·(i) General. Implement security measures sufficient to reduce risks and vulnerabilities to all electronic protected health information to a reasonable and appropriate level. (ii) Implementation specifications ·(A) Planning. Establish and implement a written risk management plan for reducing risks to all electronic protected health information, including but not limited to those risks identified by the risk analysis under paragraph (a)(2)(ii)(A) of this section, to a reasonable and appropriate level. (B) Maintenance. Review the written risk management plan required by paragraph (a)(5)(ii)(A) of this section at least once every 12 months and as reasonable and appropriate in response to changes in the risk analysis made in accordance with paragraph (a)(2)(ii)(B) of this section, and modify as reasonable and appropriate. (C) Priorities. The written risk management plan must prioritize the risks identified in the risk analysis required by paragraph (a)(2)(ii)(A) of this section, based on the risk levels determined by such risk analysis. (D) Implementation. Implement security measures in a timely manner to address the risks identified in the covered entity's or business associate's risk analysis in accordance with the priorities established under paragraph (a)(5)(ii)(C) of this section. (6) Standard: Sanction policy ·(i) General. Apply appropriate sanctions against workforce members who fail to comply with the security policies and (printed page 1014) procedures of the covered entity or business associate. (ii) Implementation specifications ·(A) Policies and procedures. Establish written policies and procedures for sanctioning workforce members who fail to comply with the security policies and procedures of the covered entity or business associate. (B) Modifications. Review written sanctions policies and procedures at least once every 12 months, and modify as reasonable and appropriate. (C) Application.

In FY 2015, collaborators and the associated collaborations have included Carnegie Mellon University (test development environment), Johns Hopkins Applied Physics Lab (the practical application of a combinatorial coverage measurement tool), the University of Texas at Arlington (a covering array generation algorithm), Mexico's Centro de Investigación y de Estudios Avanzados del Instituto Politécnico Nacional (a very large covering array generation and its application to hardware malware detection), Lockheed Martin Corporation (the practical application of covering arrays), United States Marine Corps (USMC) Camp Pendleton (testing and fault location for the tactical data link TADIL-J protocol), University of Texas Dallas and East Carolina University (safety-critical systems testing), Duke University (analysis of software failures), the National Science Foundation (cybersecurity metrics and assurance building), the National Security Agency (NSA) Information Assurance Directorate (security automation standardization), the Department of Homeland Security (DHS) Cybersecurity and Communications (security automation standardization), and DHS (incident coordination). In particular, the SSAG led the NIST Security and Forensics Working Group that published draft NISTIR 8006, NIST Cloud Computing - Security Reference Architecture, that aggregates forensics challenges in a cloud ecosystem. The working group has been working on developing a draft of SP 800-173, Guidance for Applying the Risk Management Framework to Federal-based Information Systems (target release date: spring/summer 2016).

Five respondents requested that DoD harmonize the requirements of the rule with industry- and Government-led supply chain risk management regimes and initiatives in order to avoid inconsistencies. One respondent encouraged DoD to harmonize the requirements of the rule with the guidance issued by the Secretary of Defense memorandum dated October 10, 2013, entitled ·Safeguarding Unclassified Controlled Technical Information;· the Office of Management and Budget's circular M-14-13 dated November 18, 2013, entitled ·Enhancing the Security of Federal Information and Information Systems;· and other Departmental requirements. This respondent further recommends that the final rule include a statement that ·the rule complements rather than conflicts with other related requirements.· Another respondent further encouraged DoD to avoid the creation of unneeded duplication of certifications of these important assurance efforts, by affirming that the interim rule shall not impact the duties of contractors and vendors in assessing relevant procurements related to NSS. Response: DoD is involved in a myriad of efforts to address supply chain risks, specifically, as well as cybersecurity broadly. All of these policies and strategic efforts aim to improve the overall risk posture of the Federal Government's information systems and those of its industry partners. A patchwork of policies and regulations is sometimes necessary to address the variabilities of the system ownership and operation, and the risk tolerance of the mission. The rule is specific to DoD and narrowly scoped to NSS, which often have a lower risk tolerance due to the criticality of missions utilizing such systems. 9. Tracking Comment: One respondent commented

that DoD should catalog the number of source exclusions executed under the section 806 authority between 2013 and 2018. Response: DoD is required to submit a report on January 1, 2017, on the effectiveness of section 806 authorities, to include how frequently DoD exercises the authority.

III. Applicability to Acquisitions Not Greater Than the Simplified Acquisition Threshold (SAT) and Commercial Items, Including Commercially Available Off-the-Shelf (COTS) Items Consistent with 41 U.S.C. 1905, 1906, and 1907, the Director Defense Procurement and Acquisition Policy (DPAP), determined that it would not be in the best interest of the United States to exempt acquisitions not greater than the SAT and acquisitions of commercial items, including COTS items, from the applicability of section 806 of the NDAA for FY 2011 as amended by section 806 of the NDAA for FY 2013. A. Applicability to Contracts at or Below the SAT 41 U.S.C. 1905 governs the applicability of laws to contracts or subcontracts in amounts not greater than the SAT. It is intended to limit the applicability of laws to such contracts or subcontracts. 41 U.S.C. 1905

From the NIST SP 800-172 Rev 3 Final Public Draft: The assessment procedures are based on the procedures described in SP 800-53A [15]. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 protection of CUI. To reduce the risk of collusion, organizations consider rotating 454

AU.L2-3.3.8 · Audit Protection CMMC Assessment Guide · Level 2 | Version 2.13 88 FURTHER DISCUSSION Audit information is a critical record of what events occurred, the source of the events, and the outcomes of the events; this information needs to be protected. The logs must be properly secured so that the information may not be modified or deleted, either intentionally or unintentionally. Only those with a legitimate need -to-know should have access to audit information, whether that information is being accessed directly from logs or from audit tools. Example You are in charge of IT operations in a company that handles CUI. Your responsibilities include protecting audit information and audit logging tools. You protect the information from modification or deletion by having audit log events forwarded to a central server and by restricting the local audit logs to only be viewable by the system administrators [a,b,c]. Only a small group of security professionals can view the data on the central audit server [b,c,d]. For an additional layer of protection, you back up the server daily and encrypt the backups before sending them to a cloud data repository [a,b,c]. Potential Assessment Considerations · Is there a list of authorized users for audit systems and tools [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.3.8

3.3.1 | Cipher Suites... 3.3.1, grouped by certificate type and protocol version. 3.3.1 Cipher Suites Cipher suites specify the cryptographic algorithms that will be used for a session.

(Comment 164) Several comments state that the food distribution chain is comprised of multiple links or components, some of which will qualify as small or very small businesses, such as independent truck operators or some DSD operations. For example, some large national baked goods companies deliver products directly to stores through individuals who function as independent businesses (e.g., they own their own trucks, purchase the food from the vendor and sell it to the store, and hold licenses to the particular delivery routes). The comments state that, if these businesses are covered by the small business exemption, they will not be required to provide the information that larger businesses will be required to retain. The comments recommend that FDA either extend the exemption through all subsequent links in the distribution chain, or else recognize the interconnectedness of the systems and impose a single, more realistic compliance date with which all in the food distribution chain will be able to comply, e.g., establish a universal compliance date for the regulations of June 9, 2005. (Response) FDA does not agree that all businesses should be subject to a universal compliance date. FDA has considered the interconnectedness of the food distribution system and contractual relationships that exist between very small, small, and large businesses. FDA has determined that large, small, and very small businesses will have 12, 18, and 24 months, respectively, from the date of publication of this final rule, with which to comply. These timeframes represent an extra 6 months over the timeframes in the proposed rule for all business sizes to come into compliance. FDA believes that many large businesses and possibly many small businesses already establish and maintain records that contain most or all of the information required by these regulations, and thus should not require longer than 12 and 18 months, respectively, to come into compliance. Very small firms would have 24 months to comply. FDA anticipates that the very small and small businesses will be able to lower their compliance costs by learning from the experience of the large businesses. The extended compliance times for small and very small businesses are based on the total number of full-time equivalent employees within the

entire business, not just at each individual establishment. (Comment 165) One comment notes that small businesses doing business with large businesses would have to comply with the large business timeframe and asks FDA to reconsider this exception, and allow small businesses to comply on the 12 and 18 month schedule.

Control ES-1: Information on devices used from any location. The analysis should also lead to the identification of the type or types of storage encryption technologies that can meet the organization's security needs. Another outcome of the analysis is the documentation of the requirements for the storage encryption technologies themselves, including security capabilities (e.g., authentication, cryptography, key management), performance requirements, management requirements (including reliability, interoperability, scalability), the security of the technology itself, usability (by both administrators and users), and maintenance requirements (such as applying updates). In most cases, a single storage encryption product cannot meet all of the organization's identified needs. For example, the organization may need to protect information on devices running several different OSs, yet no appropriate product can work on all those platforms. Some devices might also not meet the minimum hardware requirements for storage encryption products. Organizations can solve this problem in several ways, such as acquiring multiple products, using multiple types of storage encryption technologies, replacing older devices, or identifying compensating controls to be used instead of storage encryption that provide the same level of protection. Appendix A discusses some potential alternatives to storage encryption. Organizations should ensure that effective solutions are identified for all the types of end user devices that need their stored information protected, if possible, and that a waiver process is created for unusual cases that cannot be addressed by the identified solutions. ## 4.2 Design the Solution Once the needs have been identified and the appropriate type(s) of storage encryption technology have been chosen, the next phase is to design a solution that meets the needs. If these design decisions are incorrect, then the storage encryption implementation will be more susceptible to compromise.

Control BM-650: Feedback . This approach to data-stream encryption is very similar to the internal feedback approach, the difference being that cipher bits, rather than "encrypting bits," are used as the DES input. Itote that this approach, Figure 5, if used in a one bit feedback mode, is "self synchronizing" because after 64 bit times the DES input register of the decryption device will contain the same data as does the input register of the encryption device. Note also that the approach provides garble extension, thus providing anti-spoofing protection. ## 6 . System Philosophies There are three basic approaches to incorporating encryption into a communications system: link-by-link, nodeby-node, and end-to-end encryption. Link-by-link encryption, figure 6, is the technique most commonly used today. It may be implemented in a transparent manner with currently available devices, which are placed in series with the circuit between data terminal equipment and data communications equipment. This approach has the disadvantage that it allows all traffic to pass through the CPU of any node in plain-text. Node-by-node encryption, figure 7, is a modified version of link-by-link encryption to overcome this disadvantage. Each link uses a unique key, but the "translation" from one key to the next occurs within a single "security module" which might serve as a peripheral device to the node's CPU In this way plain-text data does not traverse the node, but exists only within this physically secure module. Note that enough message data must remain encrypted so that the node's CPU can properly route the message. End-to-end encryption, figure 8, requires a "Key Control Center," located somewhere within the communication system. Each end-point in the system holds a unique "long-term" key, and this center alone holds a copy of each such key. When one end point wishes to communicate to another, a request to this effect is sent to the Key Control Center.

PART 1-GENERAL ENFORCEMENT REGULATIONS 1. The authority citation for 21 CFR part 1 continues to read as follows: Authority: 15 U.S.C. 1453 , 1454 , 1455 ; 19 U.S.C. 1490 , 1491 ; 21 U.S.C. 321 , 331 , 332 , 333 , 334 , 335a , 343 , 350c , 350d , 352 , 355 , 360b , 362 , 371 , 374 , 381 , 382 , 393 ; 42 U.S.C. 216 , 241 , 243 , 262 , 264 . 2. New subpart J (§§ 1.326 through 1.368) is added to part 1 to read as follows: Subpart J-Establishment, Maintenance, and Availability of Records General Provisions 1.326 Who is subject to this subpart? 1.327 Who is excluded from all or part of the regulations in this subpart? 1.328 What definitions apply to this subpart? 1.329 Do other statutory provisions and regulations apply? 1.330 Can existing records satisfy the requirements of this subpart? Requirements for Nontransporters to Establish and Maintain Records to Identify the Nontransporter and Transporter Immediate Previous Sources of Food 1.337 What information must nontransporters establish and

maintain to identify the nontransporter and transporter immediate previous sources of food? Requirements for Nontransporters to Establish and Maintain Records to Identify the Nontransporter and Transporter Immediate Subsequent Recipients of Food 1.345 What information must nontransporters establish and maintain to identify the nontransporter and transporter immediate subsequent recipients of food? Requirements for Transporters to Establish and Maintain Records 1.352 What information must transporters establish and maintain? General Requirements 1.360 What are the record retention requirements? 1.361 What are the record availability requirements? 1.362 What records are excluded from this subpart? 1.363 What are the consequences of failing to establish or maintain records or make them available to FDA as required by this subpart? Compliance Dates 1.368 What are the compliance dates for this subpart? Subpart J-Establishment, Maintenance, and Availability of Records General Provisions §1.326 Who is subject to this subpart? (a) Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States are subject to the regulations in this subpart, unless you qualify for one of the exclusions in §1.327. If you conduct more than one type of activity at a location, you are required to keep records with respect to those activities covered by this subpart, but are not required by this subpart to keep records with respect to activities that fall within one of the exclusions in §1.327. (b) Persons subject to the regulations in this subpart must keep records whether or not the food is being offered for or enters interstate commerce. §1.327 Who is excluded from all or part of the regulations in this subpart? (a) Farms are excluded from all of the requirements in this subpart.

dd. Whether annual auditing of a regulated entity's compliance with the Security Rule is appropriate. ee. Whether the Department should specify the level of detail or standard required for the annual compliance audit. If so, please explain. ff. Whether the Department should require a regulated entity to obtain written verification of their business associates' implementation of the administrative and physical safeguards that are required by the Security Rule, in addition to the proposed requirement to obtain verification of implementation of the technical safeguards. If so, please explain. gg. Whether there are other requirements for which the Department should require that the person performing them have a specific level or type of expertise. If so, please explain.

E. Section 164.310-Physical Safeguards 1. Current Provisions A person with physical access to electronic media or a regulated entity's electronic information systems that create, receive, maintain, or transmit or that otherwise affect the confidentiality, integrity, and availability of ePHI might have the opportunity to change the configurations of its relevant electronic information systems, install malicious software or otherwise adversely affect technology assets in its relevant (printed page 958) electronic information systems, change information, or access ePHI or other sensitive information. [631] Any of these actions has the potential to adversely affect the confidentiality, integrity, or availability of ePHI, which means that physical safeguards for electronic media and a regulated entity's relevant electronic information systems are critical to protecting the security of ePHI. Thus, the physical safeguards standards address the essential requirements for regulated entities to apply to limit physical access to their relevant electronic information systems to only authorized workforce members. As discussed above, ePHI is increasingly transmitted using interconnected systems that rely on cloud computing. The shift to a cloud-based infrastructure may increase regulated entities' reliance on business associates to maintain and access ePHI stored in the cloud. [632] Additionally, the shift to cloud computing enables regulated entities' workforce members to access ePHI and relevant electronic information systems from a greater number of locations. Accordingly, regulated entities must appropriately expand and/or ensure that applied physical safeguards take into account these new arrangements. Section 164.310 includes the four standards with which a regulated entity must comply to physically secure relevant electronic information systems and the premises where they are located. These standards require regulated entities to implement physical safeguards for facility access controls, workstation use, workstation security, and device and media controls in a manner that conforms with 45 CFR 164.306(c) , the general compliance provision for the security standards.

(g) The DIB participant and the Government may each unilaterally limit or discontinue participation in this program at any time. Termination shall not relieve the DIB participant or the Government from obligations to continue to protect against the unauthorized use or disclosure of GFI, attribution information, contractor proprietary information, third-party proprietary information, or any other information exchanged under this program, as required by law, regulation, contract, or the FA. (h) Upon termination of the FA, and/or change of Facility Security Clearance status below Secret, GFI must be returned to the Government or destroyed pursuant to direction of, and at the

discretion of, the Government. (i) Participation in this program does not abrogate the Government's or the DIB participants' rights or obligations regarding the handling, safeguarding, sharing, or reporting of information, or regarding any physical, personnel, or other security requirements, as required by law, regulation, policy, or a valid legal contractual obligation. § 236.7 DIB participant eligibility requirements. To be eligible to participate in this program, a DIB company must: (a) Have or acquire DoD-approved medium assurance certificates to enable encrypted unclassified information sharing between the Government and DIB participants; (printed page 62438) (b) Have an existing active Facility Security Clearance (FCL) granted under the National Industrial Security Program Operating Manual (NISPOM) (DoD 5220.22-M) with approved safeguarding for at least Secret information, and continue to qualify under the NISPOM for retention of its FCL and approved safeguarding (<http://www.dtic.mil/whs/directives/corres/pdf/522022m.pdf>); (c) Have or acquire a Communication Security (COMSEC) account in accordance with the NISPOM Chapter 9, Section 4 (DoD 5220.22-M), which provides procedures and requirements for COMSEC activities; (d) Obtain access to DoD's secure voice and data transmission systems supporting the DIB CS/IA program, (e) Own or operate covered DIB system(s), and (f) Execute the standardized FA with the Government (available during the application process), which implements the requirements set forth in §§ 236.4 through 236.6. Dated: September 30, 2013. Patricia L. Toppings, OSD Federal Register Liaison Officer, Department of Defense. [FR Doc. 2013-24256 Filed 10-21-13; 8:45 am] BILLING CODE 5001-06-P

(Response) For the reasons stated in the previous paragraphs, FDA continues to believe that facilities that provide food to interstate conveyances should not be covered by the restaurant exclusion because they do not prepare and sell food directly to the consumer for immediate consumption. However, the comment's concern about having to go to unprecedented lengths to ensure strict batch preparation misconstrues the proposed requirement. In the final rule, FDA deleted the requirement in § 1.337(a) for a nontransporter to provide information reasonably available to identify the specific source of each ingredient used to make every lot of finished product, and instead put that requirement in § 1.345(b) of this final rule because it is unlikely that a person would have that information reasonably available at the time records are created to identify the immediate previous sources of the food. FDA acknowledges that certain business practices are not amenable to linking incoming ingredients with outgoing product and that it may not always be possible to identify the specific source of an ingredient that was used to make a lot of finished product. It is not FDA's intent to mandate reengineering of long-standing existing processes. Accordingly, the final rule requires linking incoming with outgoing product only when this information is reasonably available. Although the definition of restaurant has not changed from the proposed definition, FDA exercised its discretion and added language to the restaurant exclusion in § 1.327(b) of this final rule to account for incidental sales of food that a restaurant/retail facility does not prepare itself (e.g., food it purchases from a manufacturer for sale to consumers). See the discussion earlier in section III.E.14 of this document. 15. Retail Facility As explained in response to comment 40 of this document, for purposes of § 1.327(e) of this final rule, retail food establishment is defined to mean an establishment that sells food products directly to consumers as its primary function. The term consumers does not include businesses. A retail food establishment may manufacture/process, pack, or hold food if the establishment's primary function is to sell from that establishment food, including food that it manufactures/processes, packs, or holds, directly to consumers. A retail food establishment's primary function is to sell food directly to consumers if the annual monetary value of sales of food products directly to consumers exceeds the annual monetary value of sales of food products to all other buyers. A retail food establishment includes grocery stores, convenience stores, and vending machine locations. In addition, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from the requirements in subpart J of this final rule, except §§ 1.361 and 1.363. (See response to comment 38 of the document for a further discussion of FDA's rationale underlying this exclusion.) (

Agency records, which may include qualifying information received from non-federal entities, are subject to request under the Freedom of Information Act (5 U.S.C. 552) (FOIA), which is implemented in the Department of Defense by DoD Directive 5400.07 and DoD Regulation 5400.7-R (see 32 CFR parts 285 and 286 , respectively). Pursuant to established procedures and applicable regulations, the Government will protect sensitive nonpublic information under this Program against unauthorized public disclosure by asserting applicable FOIA exemptions, and will inform the non-Government source or submitter (e.g., DIB participants) of any such information that may be subject

to release in response to a FOIA request, to permit the source or submitter to support the withholding of such information or pursue any other available legal remedies. §-236.6 General provisions. (a) Confidentiality of information that is exchanged under this program will be protected to the maximum extent authorized by law, regulation, and policy. (b) The Government and DIB participants will conduct their respective activities under this program in accordance with applicable laws and regulations, including restrictions on the interception, monitoring, access, use, and disclosure of electronic communications or data. The Government and the DIB participant each bear responsibility for their own actions under this program. (c) Prior to sharing any information with the Government under this program pursuant to the FA, the DIB participant shall perform a legal review of its policies and practices that support its activities under this program, and shall make a determination that such policies, practices, and activities comply with applicable legal requirements. The Government may request from any DIB participant additional information or assurances regarding such DIB participant's policies or practices, or the determination by the DIB participant that such policies or practices comply with applicable legal requirements. (d) This voluntary DIB CS/IA program is intended to safeguard covered defense information. None of the restrictions on the Government's use or sharing of information under the DIB CS/IA program shall limit the Government's ability to conduct law enforcement, counterintelligence activities, or other activities in the interest of national security; and participation does not supersede other regulatory or statutory requirements. (e) Participation in the DIB CS/IA program is voluntary and does not obligate the DIB participant to utilize the GFI in, or otherwise to implement any changes to, its information systems. Any action taken by the DIB participant based on the GFI or other participation in this program is taken on the DIB participant's own volition and at its own risk and expense.

means any communication or representation of knowledge such as facts, data, or opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, electronic, or audiovisual forms (see Office of Management and Budget (OMB) Circular No. A-130, Managing Information as a Strategic Resource). Lawful Government purpose means any activity, mission, function, operation, or endeavor that the Government authorizes or recognizes as within the scope of its legal authorities or the legal authorities of non-executive branch entities such as state and local law enforcement. (b) Identifying and reporting information the contractor believes or has reason to know is potentially CUI. This contract does not identify CUI as being involved in the contract; nonetheless: (1) The Contractor shall notify the Contracting Officer within 8 hours of discovery if the Contractor discovers any information that the contractor believes, or has reason to know, is CUI. The potential unidentified CUI may be marked, unmarked, or improperly marked. The Contractor shall take action to appropriately safeguard any information the Contractor believes is CUI, until a Contracting Officer makes a determination. (2) If the Contractor discovers any information that the Contractor believes is CUI and it is involved in a suspected or confirmed CUI incident, the Contractor shall notify the Contracting Officer as outlined in paragraph (b)(1), determine and inventory what CUI was or could have been improperly accessed, created, collected, used, processed, stored, maintained, disseminated, disclosed, or disposed of as part of the incident, and follow any additional incident response requirements the Contracting Officer provides if the Government determines the information is CUI. (3) The reporting requirements of this clause do not relieve the Contractor from the requirement to follow any applicable laws, regulations, or policies outside of this clause. (c) Government-provided information. The Contractor is not entitled to use Government-provided information for its own purposes, whether or not the information is marked as CUI, unless the information is in the public domain, or unless the information was lawfully made available to the Contractor by someone other than the Government. (d) Contractor information. The Contractor shall appropriately identify information the Contractor owns and provides to the Government (i.e., contractor bid or proposal information, contractor-attributional information, or contractor proprietary business information). The Government will determine in accordance with agency procedures whether the information provided by the Contractor is CUI or entitled to other protections (e.g., contractor-attributional information associated with a CUI incident). (1) If it is CUI or entitled to other protections, the Government will protect against the improper use or release of the information to the extent required by law.

Control TG-15: cribed earlier, though primitive. having common objectives, generally require complicated programming to accomplish their goals using today's tools. access logs for audit purposes could be developed. Higher level software to Elements in the various tools are often not coordinated, e.g. tracing and mapping . used together, and facilities could be developed so that

they could be used together. These techniques are generally appropriate to be 11-20 · 10.

CONCLUSIONS AND RECOMMENDATIONS Information should be published for the benefit of auditors on "what" audit tools are available "where". for security audit should be developed. This catalog would provide details of components, and would be indexed according to techniques, hardware, and software required to use the tools. Comments about the level of difficulty would also be included. That is, a catalog of tools Security log data should be built into new systems during their development. development and design of systems, to insure auditability. Security oriented personnel should participate in planning, Secure logging hardware components should be explored, to provide tamper-proof recording capability for security audit purposes. 11. REFERENCES 1. Control and Audit. William C. Mair, Donald R. Wood, Keagle W. Davis. The Institute of Internal Auditors, Inc. Second Edition Revised and Enlarged, 1976. 2. Features of Seven Audit Software Packages Principles and Capabilities. A. J. Neumann . Special Publication National Bureau of Standards, July 1977. NBS 500-13. 3. Management Controls for Data Processing. International Business Machines Corporation. GF 20-0006-1, Second Edition, April 1976. 4. Stanford Research Institute, Systems Auditability and Control Study, -Executive Report. n-21 : PART XII: INTERACTIVE AUDIT TOOLS AND TECHNIQUES Chairperson: Hart J. Will University of British Columbia Participants Robert P. Blanc Robert S.

(iii) Final Level 3 (DIBCAC). The OSC has achieved the CMMC Status of Final Level 3 (DIBCAC) if the Level 3 certification assessment results in a passing score as defined in § 170.24. This score may be achieved upon initial certification assessment or as the result of a POA&M closeout certification assessment, as applicable. (iv) CMMC Status investigation. The DoD reserves the right to conduct a DCMA DIBCAC assessment of the OSC, as provided for under the 48 CFR 252.204-7020 . If the investigative results of a subsequent DCMA DIBCAC assessment show that adherence to the provisions of this part have not been achieved or maintained, these DCMA DIBCAC results will take precedence over any pre-existing CMMC Status. At that time, standard contractual remedies will be available and the OSC will be ineligible for additional awards with CMMC Status requirement of Level 3 (DIBCAC) for the information system within the CMMC Assessment Scope until such time as a new CMMC Status is achieved. (2) Affirmation. Affirmation of the Level 3 (DIBCAC) CMMC Status is required for all Level 3 certification assessments at the time of each assessment, and annually thereafter. Affirmation procedures are provided in § 170.22. (printed page 83231) (b) Contract eligibility. Prior to award of any contract or subcontract with requirement for CMMC Status of Level 3 (DIBCAC), the following two requirements must be met: (1) The OSC must achieve, as specified in paragraph (a)(1) of this section, a CMMC Status of either Conditional Level 3 (DIBCAC) or Final Level 3 (DIBCAC). (2) The OSC must submit an affirmation of compliance into SPRS, as specified in paragraph (a)(2) of this section. (c) Procedures ·(1) Level 3 certification assessment of the OSC. The CMMC Level 3 certification assessment process includes: (i) Final Level 2 (C3PAO). The OSC must achieve a CMMC Status of Final Level 2 (C3PAO) for information systems within the Level 3 CMMC Assessment Scope prior to the CMMC Level 3 certification assessment. The CMMC Assessment Scope for the Level 3 certification assessment must be equal to, or a subset of, the CMMC Assessment Scope associated with the OSC's Final Level 2 (C3PAO). Asset requirements differ for each CMMC Level. Scoping differences are set forth in § 170.19. (ii) Initiating the Final Level 3 (DIBCAC). The OSC (including ESPs that voluntarily elect to undergo a Level 3 certification assessment) initiates a Level 3 certification assessment by emailing a request to DCMA DIBCAC point of contact found at www.dcma.mil/DIBCAC . The request must include the Level 2 certification assessment unique identifier. DCMA DIBCAC will validate the OSC has achieved a CMMC Status of Level 2 (C3PAO) and will contact the OSC to schedule their Level 3 certification assessment. (iii) Conducting the Final Level 3 (DIBCAC).

Revising the date of the clause; and b. Redesignating paragraph (c)(1)(xxi) as (c)(1)(xxiii) and adding new paragraphs (c)(1)(xxi) and (xxii). The revisions read as follows: 52.244-6 Subcontracts for Commercial Products and Commercial Services. * * * * * Subcontracts for Commercial Products and Commercial Services (DATE) * * * * * (c)(1) * * * (xxi) 52.239-YY Federal Information Systems Using Non-Cloud Computing Services (DATE) (E.O. 14028 and 15 U.S.C. 278g-3e) if flow down is required in accordance with paragraph (n) of FAR clause 52.239-YY. (xxii) 52.239-XX Federal Information Systems Using Cloud Computing Services (DATE) (E.O. 14028) if flow down is required in accordance with paragraph (i) of FAR clause 52.239-XX. * * * * * [FR Doc. 2023-21327 Filed 10-2-23; 8:45 am] BILLING CODE 6820-EP-P

The Department currently has no plans for separate reimbursement of costs to acquire cybersecurity capabilities or a required cybersecurity certification that may be incurred by an offeror on a DoD

contract. Costs may be recouped via competitively set prices, as companies see fit. (printed page 89070) c. Alternative Implementation Comment: Multiple commenters requested that the government give small businesses time for CMMC compliance post-contract award. One commenter recommended that DoD consider only requiring government assessment of NIST SP 800-171 compliance (vice private third party) for small businesses, even at lower CMMC assessment levels, thus offsetting a higher burden level to small businesses. Several commenters commented on the need to include exemptions for small businesses that do not possess CUI and have never been contracted by the government. One added that DoD should identify portions of contracts which won't require CMMC so that small businesses are afforded maximum practicable opportunity regardless of their CMMC status. Response: The DoD has determined that the assessment of the ability of a prospective contractor to adequately protect FCI and CUI that will be processed, stored, or transmitted on information systems during contract performance is a requirement prior to award of any prime contract or subcontract. Failure to assess a prospective contractor's ability to comply with applicable information security protection requirements, such as NIST SP 800-171 Rev 2, risks significant performance delays if information cannot be shared immediately at contract award due to lack of compliance. As applicable, the awardee must be capable of processing, storing, and transmitting FCI and CUI at the start of the performance period, regardless of the business size of the awardee. The CMMC Program has simplified requirements for Level 1 and 2 assessments in some contracts. Specifically, although contractors must still implement and maintain the security requirements set forth in FAR 52.204-21 to protect FCI and set forth in the NIST SP 800-171 Rev 2 to protect CUI, the requirement to hire a third-party assessment organization for CMMC Level 1 was eliminated, and for some contracts, contractors may be permitted to self-assess compliance with CMMC Level 2. Annual affirmations are also required for CMMC Level 1 and 2. Prospective contractors must make a business decision regarding the type of DoD business they wish to pursue and understand the implications for doing so. If an offeror or current DoD contractor or subcontractor has self-assessed then later decides to pursue a contract or subcontract requiring a certification at CMMC Level 2 or 3, it will need to factor in the time and investment necessary to hire a third-party assessment organization and achieve certification as a condition of contract award.

3.8.2 Public Key-Transport Keys... 3.8.2 Public Key-Transport Keys Backup or archiving of the public key may be done but may not be necessary.

d levels of expertise and significant resources that allow it to create opportunities to achieve its objectives by using multiple attack vectors including, for example, cyber, physical, and deception. These objectives typically include establishing and extending footholds within the IT infrastructure of the targeted organizations for purposes of exfiltrating information, undermining or impeding critical aspects of a mission, program, or organization, or positioning itself to carry out these objectives in the future. The advanced persistent threat pursues its objectives repeatedly over an extended period; adapts to defenders' efforts to resist it; and is determined to maintain the level of interaction needed to execute its objectives. Note 1: While some sources define APT (or advanced cyber threat) as an adversary at Tier V or Tier VI in the threat model in [DSB13] in particular, to be a state actor the definition used here includes criminal actors. Note 2: For brevity, the APT refers to any adversary with the characteristics described above or to the set of all such adversaries; an APT actor refers to a representative member of that set. Note 3: The APT may establish its foothold by subverting the supply chain in order to compromise cyber resources. Thus, the APT may be able to achieve its objectives without executing a cyber-attack against the organization's systems (e.g., by inserting a logic bomb or time). Note 4: The term APT does not include the insider threat. However, if an APT actor establishes and extends its foothold by masquerading as a legitimate system user and taking advantage of that user's authorized access privileges, it may be indistinguishable from an insider threat.

(I) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to that individual, and record amendment procedures for this record system. (J) From subsection (g) because this system of records should be exempt to the extent that the civil remedies relate to provisions of 5 U.S.C. 552 a from which this rule exempts the system. (iv) Exemption. (A) Investigative material compiled for law

enforcement purposes, other than material within the scope of subsection (j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigative material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), (printed page 14788) but only to the extent that such material would reveal the identity of a confidential source. (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and/or (k)(5) from the following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (H) and (I), and (f). (v) Authority. 5 U.S.C. 552a(k)(2) and (k)(5). (vi) Reasons. (A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation or prosecutable interest by the NRO or other agencies. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence.

3.6.2 Security for Routing Protocols Routing protocols can be subject to threats such as unauthorized updates for either IPv4 or IPv6 routes.

Information as to current military addresses and assignments may be provided to military banking facilities who provide banking services overseas and who are reimbursed by the Government for certain checking and loan losses. For personnel separated, discharged, or retired from the Armed Forces, information as to last known residential or home of record address may be provided to the military banking facility upon certification by a banking facility officer that the facility has a returned or dishonored check negotiated by the individual or the individual has defaulted on a loan and that if restitution is not made by the individual, the U.S. Government will be liable for the losses the facility may incur. K. Routine Use-Disclosure of Information to the General Services Administration A record from a system of records maintained by a Component may be disclosed as a routine use to the General Services Administration (GSA) for the purpose of records management inspections conducted under authority of 44 U.S.C. 2904 and 2906. L. Routine Use-Disclosure of Information to the National Archives and Records Administration A record from a system of records maintained by a Component may be disclosed as a routine use to the National Archives and Records Administration (NARA) for the purpose of records management inspections conducted under authority of 44 U.S.C. 2904 and 2906. M. Routine Use-Disclosure to the Merit Systems Protection Board A record from a system of records maintained by a Component may be disclosed as a routine use to the Merit Systems Protection Board, including the Office of the Special Counsel, for the purpose of litigation, including administrative proceedings, appeals, special studies of the civil service and other merit systems, review of OPM or Component rules and regulations, investigation of alleged or possible prohibited personnel practices, including administrative proceedings involving any individual subject of a DoD investigation, and such other functions, promulgated in 5 U.S.C. 1205 and 1206 or as may be authorized by law. N. Routine Use-Counterintelligence Purposes A record from a system of records maintained by a Component may be disclosed as a routine use outside the Department of Defense (DoD) or the U.S. Government for the purpose of counterintelligence activities authorized by U.S. law or Executive Order or for the purpose of enforcing laws that protect the national security of the United States. (printed page 18785) Appendix D to Part 310-Provisions of the Privacy Act From Which a General or Specific Exemption May Be Claimed (See paragraph (d) of §310.26) Exemptions Section of the Privacy Act (j)(2) (k) (1-7) No No (b)(1) Disclosures within the Department of Defense. No No (2) Disclosures to the public. No No (3) Disclosures for a Routine Use. No No (4) Disclosures to the Bureau of Census. No No (5) Disclosures for statistical research and reporting. No No (6) Disclosures to the NARA. No No (7) Disclosures for law enforcement purposes. No No

(i) Copies of the request; (ii) Copies of the Component's action granting total or partial access. (Note: A separate Privacy case file need not be created in such cases.) (iii) Copies of the Component's action denying access. (iv) Copies of any appeals filed. (v) Copies of the reply to the appeal. (6) Privacy case files shall not be furnished or disclosed to anyone for use in making any determination about the individual other than determinations made under this part. §310.20

Reproduction fees. (a) Assessing fees. (1) Charge the individual only the direct cost of reproduction. (2) Do not charge reproduction fees if copying is: (i) The only means to make the record available to the individual (for example, a copy of the record must be made to delete classified information); or (ii) For the convenience of the DoD Component (for example, the Component has no reading room where an individual may review the record, or reproduction is done to keep the original in the Component's file). (iii) No fees shall be charged when the record may be obtained without charge under any other Regulation, Directive, or statute. (iv) Do not use fees to discourage requests. (b) No minimum fees authorized. Use fees only to recoup direct reproduction costs associated with granting access. Minimum fees for duplication are not authorized and there is no automatic charge for processing a request. (c) Prohibited fees. Do not charge or collect fees for: (1) Search and retrieval of records; (2) Review of records to determine releasability; (3) Copying records for the DoD Component convenience or when the individual has not specifically requested a copy; (4) Transportation of records and personnel; or (5) Normal postage. (d) Waiver of fees. (1) Normally, fees are waived automatically if the direct costs of a given request are less than \$30. This fee waiver provision does not apply when a waiver has been granted to the individual before, and later requests appear to be an extension or duplication of that original request. A DoD Component may, however, set aside this automatic fee waiver provision when, on the basis of good evidence, it determines the waiver of fees is not in the public interest. (2) Decisions to waive or reduce fees that exceed the automatic waiver threshold shall be made on a case-by-case basis. (e) Fees for Members of Congress. Do not charge members of Congress for copying records furnished even when the records are requested under the Privacy Act on behalf of a constituent (See § 310.22(i)). When replying to a constituent inquiry and the fees involved are substantial, consider (printed page 18771) suggesting to the Congressman that the constituent can obtain the information directly by writing to the appropriate offices and paying the costs. When practical, suggest to the Congressman that the record can be examined at no cost if the constituent wishes to visit the custodian of the record. (f) Reproduction fees computation. Compute fees using the appropriate portions of the fee schedule in

Details for completion of the annual affirmation, including wording of the affirmation statement, are addressed in the 48 CFR part 204 CMMC Acquisition rule. The affirmation signifies the requirements were implemented as of the date of the self-assessment or certification, and that the OSA has and intends to maintain the system as assessed. The DoD declines to require the use of an executive summary or the publication of metrics in the affirmation statement as part of the affirmation because that is not consistent with the purpose of the affirmation requirement. Regarding the alignment of assessments and affirmation timelines, the DoD declines to adopt recommended changes which would allow up to 3 years to elapse before DIB companies would be required to assess the status of their cybersecurity compliance. 25. CMMC Acceptance of Alternate Standards a. CMMC and Other Agency Standards or Acceptance of CMMC Assessments Comment: Several commenters asked for additional detail about § 170.20 Standards Acceptance. One commenter described discussions from various DoD industry engagements and suggested the rule is inconsistent with information provided at those information exchange events. Some commenters observed the rule does not describe DoD efforts to coordinate with other agencies regarding any additional cybersecurity requirements they choose to implement, which could conflict or add burden for companies that must also comply CMMC requirements. One comment suggested implementing the CMMC program government wide. An industry association submitted several comments regarding perceived duplication between this rule and cybersecurity requirements of other Federal agencies and foreign governments. They also recommended the DoD modify the rule to reflect other agency standards, such as TSA and CISA security directives requiring cyber incident reporting for natural gas utilities. Several commenters thought the rule did not adequately explain potential portability of CMMC assessments, referring to whether other agencies might recognize CMMC compliance as meeting or partially meeting their requirements. One specifically suggested CMMC affirmations could be accepted as evidence of compliance with any similar cybersecurity requirements other agencies may implement. One comment suggested that by assessing compliance of all applicable security requirements, the CMMC program will impede efforts to establish DoD information sharing agreements with other non-DoD organizations, including other agencies and foreign governments. Response: Some comments received lacked relevance to the rule's content, which is limited to specific CMMC Program requirements. The DoD declines to respond to speculative or editorial comments about private citizens or entities, all of which are not within the scope of this rule. Similar data security requirements are already applied to contractors across all Federal agencies, due to the applicability of FAR clause 52.204-21, and 32 CFR part 2002

From the NIST SP 800-172 Rev 3 Final Public Draft: (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800- NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 53B, Includes updates as of December 10, 2020. <https://doi.org/10.6028/NIST.SP.800-53B.2675>

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 architectures can also include other information, such as user roles and the access 2424

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations. Bluetooth was originally conceived by Ericsson in 1994. Ericsson, IBM, Intel, Nokia, and Toshiba formed the Bluetooth Special Interest Group (SIG), a not-for-profit trade association developed to drive development of Bluetooth products and serve as the governing body for Bluetooth specifications. 3 Bluetooth is standardized within the IEEE 802.15 Working Group for Wireless Personal Area Networks that formed in 1999 as IEEE 802.15.1-2002. 4

The IoT Cybersecurity Program coordinated outreach to a range of public and private sector stakeholders to inform them of NIST's IoT cybersecurity work and collect feedback to inform future work. This included sessions at the Cybersecurity Framework Workshop in 2017, the Industrial Internet Consortium (IIC) quarterly meeting, and planning a colloquium with industry, government, and academic participants. - FISMA Outreach Activity to Public and Private-Sector Organizations: Cybersecurity outreach briefings were conducted and support was provided to all levels of private sector organizations and government (including federal, state and local entities) on multiple information security topics of interest. These included, for example, an effective implementation of the NIST RMF, contingency planning, interconnection security agreements, security-focused configuration management, and information security for small businesses. In addition, the ITL FISMA Team responded to hundreds of inquiries from customers, served on cybersecurity advisory panels, conducted outreach activities with academic institutions, provided information on NIST's security standards and guidelines, and explored new areas of cybersecurity research and development. - Collaboration with JTF partners and other federal organizations: The FISMA Team worked closely with JTF partners to ensure that the five JTF publications remain current, and to designate additional Special Publications as JTF guidance. The five JTF publications are: 1. SP 800-30, Guide for Conducting Risk Assessments; 2. SP 800-37, Guide for Applying the Risk Management Framework to Federal Information Systems: a Security Life Cycle Approach; 3. SP 800-39, Managing Information Security Risk: Organization, Mission, and Information System View; 4. SP 800-53, Security and Privacy Controls for Federal Information Systems and Organizations; and 5.

s without permission. They also believe that the professional societies should take the lead in public education about the need for responsible use of critical data now stored extensively in computers. Similarly, system administrators have responsibilities to take steps that will minimize the risk of disruption: they should not tolerate trapdoors, which permit access without authentication; they should strengthen password authentication procedures to block guessed-password attacks; they should isolate their backup systems from any Internet connection; and they should limit participation in mutually trusting groups.

(ii) Any administrative access must be conducted using a hardware-based multifactor cryptographic

device authenticator. (2) Administrative accounts. (i) All systems and services provided shall have unique administrative accounts, with the exception of service accounts. (ii) Any accounts that administer any part of a system used in the performance of the contract, to include support systems and infrastructure, shall be considered part of the system authorization boundary and must have unique administrative accounts that are unique and exclusive to agency systems. Administrator accounts must be disclosed, upon request by the contracting officer. (3) Consent banners. Login and consent banners must be deployed on all systems and networks. Such banners must be consistent with CISA guidance at <https://www.cisa.gov/publication/guidance-consent-banners>. The contract may include more specific requirements for consent banners; such requirements will be consistent with the CISA guidance linked above. 39.X03 Contracting officer coordination. The contracting officer shall coordinate the following requests and submissions with the requiring activity (to enable coordination with the agency chief information security officer, senior agency official for privacy, and agency legal counsel, as necessary). (a) Any request for information or access pursuant to the clause at 52.239-ZZ, Incident and Threat Reporting and Incident Response Requirements for Products or Services Containing Information and Communications Technology (ICT); (b) A submission of a reportable incident pursuant to FAR clause 52.239-ZZ, when such incident involves a FIS; (c) The contractor's annual, independent assessment of the security of each FIS (52.239-YY(d)(1)(iii)). If received from the requiring activity, the contracting officer shall provide the contractor with the agency's request to implement or rationale for not implementing a recommendation for improvement or mitigation (52.239-YY(d)(1)(iv) and (v)); (d) A contractor's request to use Government-related data for a purpose other than to manage the operational environment that supports the Government data information (52.239-XX(d)(2)); (e) A contractor's submission of its system security plan, when requested by the agency (52.239-YY(e)(3)(ii)); (printed page 68417) (f) A contractor's submission of its continuous monitoring strategy for the FIS (52.239-YY(f)(7)); (g) A contractor's request to implement alternative, additional, or compensating security controls, to include those pertaining to cyber supply chain risk management, not otherwise identified in the contract (52.239-YY(g)); (h) A contractor's request to use Government metadata for a purpose other than to manage the operational environment that supports the Government data (52.239-YY(i)(2));

(E) An individual performing private security functions has come under attack including in cases where a weapon is discharged against an individual performing private security functions or personnel performing such functions believe a weapon was so discharged; or (F) Active, non-lethal counter-measures (other than the discharge of a weapon) are employed by PSC personnel in response to a perceived immediate threat in an incident that could significantly affect U.S. objectives with regard to the military mission or international relations. (Active non-lethal systems include laser optical distracters, acoustic hailing devices, electro-muscular TASER guns, blunt-trauma devices like rubber balls and sponge grenades, and a variety of riot-control agents and delivery systems). (vi) The independent review and, if practicable, investigation of incidents reported pursuant to paragraphs (a)(1)(v)(A) through (a)(1)(v)(F) of this section and incidents of alleged misconduct by PSC personnel. (vii) Identification of ultimate criminal jurisdiction and investigative responsibilities, where conduct of U.S.G.-funded PSCs or PSC personnel are in question, in accordance with applicable laws to include a recognition of investigative jurisdiction and coordination for joint investigations (i.e., other U.S.G. agencies, host nation, or third country agencies), where the conduct of PSCs and PSC personnel is in question. (viii) A mechanism by which a commander of a combatant command may request an action by which PSC personnel who are non-compliant with contract requirements are removed from the designated operational area. (ix) Interagency coordination of administrative penalties or removal, as appropriate, of non-DoD PSC personnel who fail to comply with the terms and conditions of their contract, as they relate to this part. (x) Implementation of the training requirements contained below in paragraph (a)(2)(ii) of this section. (2) Specifically cover: (i) Matters relating to authorized equipment, force protection, security, health, safety, and relations and interaction with locals in accordance with DoD Instruction 3020.41, Contractor Personnel Authorized to Accompany the U.S. Armed Forces. (ii) Predeployment training requirements addressing, at a minimum, the identification of resources and assistance available to PSC personnel as well as country information and cultural training, and guidance on working with host country nationals and military personnel. (iii) Rules for the use of force and graduated force procedures. (iv) Requirements and procedures for direction, control and the maintenance of communications with regard to the movement and coordination of PSCs and PSC personnel, including specifying interoperability requirements. These include coordinating with the Chief of Mission, as necessary, private security operations outside secure bases and U.S. diplomatic

properties to include movement control procedures for all contractors, including PSC personnel. (b)

a. Whether the Department should require a regulated entity to implement any additional administrative safeguards. If so, please explain. b. Whether the Department should not require a regulated entity to implement any of the existing or proposed standards for implementation specifications. If so, please explain. c. Whether there are additional implementation specifications that should be adopted for any of the standards for administrative safeguards. d. Whether the Department should provide any exceptions to the administrative safeguards or related implementation specifications. If so, please explain when and why any exceptions should apply. e. Whether once every 12 months is the appropriate frequency between reviews of policies, procedures, and other activities required by the other standards for administrative safeguards. f. Whether there are any special considerations for business associates and business associate agreements that the Department should be aware of with respect to administrative safeguards. g. Whether there are any requirements for business associates and business associate agreements that the Department should include in administrative safeguards that it did not propose. h. Whether the Department should require covered entities to report to their business associates (or business associates to their subcontractors) the activation of the covered entities' (or business associates') contingency plans. If so, please explain the appropriate circumstances of and the appropriate amount of time for such notification. i. Whether once every 12 months is an appropriate length of time in which a covered entity must verify and document that a business associate has deployed technical safeguards pursuant to the requirements. j. Whether the Department should require covered entities to obtain satisfactory assurances and verify that a business associate has implemented physical or other safeguards in addition to deploying technical safeguards before permitting it to create, receive, maintain, or transmit ePHI on its behalf. k. Whether on an ongoing basis, but at least once every 12 months and when there is a change to a regulated entity's environment or operations that affects ePHI, is the appropriate frequency for updating the technology asset inventory and network map? l. Whether on an ongoing basis, but at least once every 12 months and when there is a change to the regulated entity's environment or operations that affects ePHI, is the appropriate frequency for performing a risk analysis? m. Whether there are additional events for which the Department should require a regulated entity to update its risk analysis. If so, please explain. n. Whether the Department should include or exclude any specific circumstances from its explanation of environmental or operational changes when determining whether review or update of the written inventory of technology assets and network map or review of the risk analysis written assessment is warranted.

Audit record reduction is a process that manipulates collected audit information and organizes such information in a summary format that is more meaningful to analysts. Audit record reduction and report generation capabilities do not always emanate from the same system or organizational entities conducting auditing activities. Audit record reduction capability can include, for example, modern data mining techniques with advanced data filters to identify anomalous behavior in audit records. The report generation capability provided by the system can help generate customizable reports. Time ordering of audit records can be a significant issue if the granularity of the time stamp in the record is insufficient. 72 NIST SP 800-171A, p. 23. 73 NIST SP 800-171 Rev. 2, p. 19.

(iii) In accordance with § 170.19(c)(2), the OSC's on-premises infrastructure connecting to the CSP's product or service offering is part of the CMMC Assessment Scope. As such, the security requirements from the CRM must be documented or referred to in the OSC's SSP. (6) Level 2 certification assessment with the use of an External Service Provider (ESP), not a CSP. An OSA may use an ESP that is not a CSP to process, store, or transmit CUI in performance of a contract or subcontract with a requirement for the CMMC Status of Level 2 (C3PAO) under the following circumstances: (i) The use of the ESP, its relationship to the OSA, and the services provided are documented in the OSA's SSP and described in the ESP's service description and customer responsibility matrix. (ii) The ESP services used to meet OSA requirements are assessed within the scope of the OSA's assessment against all Level 2 security requirements. (iii) In accordance with § 170.19(c)(2), the OSA's on-premises infrastructure connecting to the ESP's product or service offering is part of the CMMC Assessment Scope, which will also be assessed. As such, the security requirements from the CRM must be documented or referred to in the OSA's SSP. § 170.18 CMMC Level 3 certification assessment and affirmation requirements. (a) Level 3 certification assessment. To comply with Level 3 certification assessment requirements, the OSC must meet the requirements set

forth in paragraphs (a)(1) and (2) of this section. An OSC undergoes a Level 3 certification assessment as detailed in paragraph (c) of this section to achieve a CMMC Status of either Conditional or Final Level 3 (DIBCAC). A CMMC Status of Final Level 2 (C3PAO) for information systems within the Level 3 CMMC Assessment Scope is a prerequisite to undergo a Level 3 certification assessment. CMMC Level 3 recertification also has a prerequisite for a new CMMC Level 2 assessment. Achieving a CMMC Status of Level 3 (DIBCAC) also satisfies the requirements for CMMC Statuses of Level 1 (Self), Level 2 (Self), and Level 2 (C3PAO) set forth in §§ 170.15 through 170.17 respectively for the same CMMC Assessment Scope. (1) Level 3 certification assessment requirements. The OSC must achieve a CMMC Status of Final Level 2 (C3PAO) on the Level 3 CMMC Assessment Scope, as defined in § 170.19(d), prior to initiating a Level 3 certification assessment, which will be performed by DCMA DIBCAC (www.dcmamil/DIBCAC)

NISTIR 8333 ## Workshop Summary Report for 'Cybersecurity Risks in Consumer Home Internet of Things (IoT) Devices' Virtual Workshop Katerina N. Megas Michael Fagan Barbara Cuthill Mary Raguso John Wiltberger This publication is available free of charge from: <https://doi.org/10.6028/NIST.IR.8333> <!-- image --> ## NISTIR 8333 ## Workshop Summary Report for 'Cybersecurity Risks in Consumer Home Internet of Things (IoT) Devices' Virtual Workshop Katerina N. Megas Michael Fagan Barbara Cuthill Applied Cybersecurity Division Information Technology Laboratory Mary Raguso John Wiltberger The MITRE Corporation McLean, VA This publication is available free of charge from: <https://doi.org/10.6028/NIST.IR.8333> March 2021 <!-- image --> U.S. Department of Commerce Gina Raimondo, Secretary National Institute of Standards and Technology James K. Olthoff, Performing the Non-Exclusive Functions and Duties of the Under Secretary of Commerce for Standards and Technology & Director, National Institute of Standards and Technology ## National Institute of Standards and Technology Interagency or Internal Report 8333 23 pages (March 2021) ## This publication is available free of charge from: <https://doi.org/10.6028/NIST.IR.8333> Certain commercial entities, equipment, or materials may be identified in this document in order to describe an experimental procedure or concept adequately. Such identification is not intended to imply recommendation or endorsement by NIST, nor is it intended to imply that the entities, materials, or equipment are necessarily the best available for the purpose. There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications.

(5) Within 30 working days, the Denial Authority will provide the following notification to the requester in writing if the decision is to deny the requester access to the information. (6) Included in the notification will be: (i) Denying Official's name, position title, and business address; (ii) Date of the denial; (iii) The specific reason for the denial, citing the appropriate subsections of the Privacy Act, the Freedom of Information Act, AR 25-55, The Department of the Army Freedom of Information Act Program and this part; and (iv) The individual's right to administratively appeal the denial within 60 calendar days of the mailing date of the notice, through the Denial Authority, to the Office of the General Counsel, Secretary of the Army, 104 (printed page 24502) Army Pentagon, Washington, DC 20310-0104. (7) The appeal must be in writing and the requester should provide a copy of the denial letter and a statement of their reasons for seeking review. (8) For denials made by the DA when the record is maintained in a Government-wide system of records, an individual's request for further review must be addressed to each of the appropriate government Privacy Act offices listed in the Privacy Act system of records notices. For a current listing of Government-wide Privacy Act system of records notices see the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy> or DA PAM 25-51. (j) No records determinations. (1) Since a no record response may be considered an 'adverse' determination, the Denial Authority must make the final determination that no records exist. The originating agency shall notify the requester that an initial determination has been made that there are no responsive records, however the final determination will be made by the Denial Authority. A no records certificate must accompany a no records determination that is forwarded to the Denial Authority. (2) The Denial Authority must provide the requester with appeal rights. (k) Referral of requests. (1) A request received by a DA activity having no records responsive to a request shall be referred to another DOD Component or DA activity, if the other Component or activity confirms that they have the requested records, or verifies that they are the proper custodian for that type of record. The requester will be notified of the referral. In cases where the DA activity receiving the request has reason to believe that the existence or nonexistence of the record may in itself be classified, that

activity will consult the Component or activity having cognizance over the records in question before referring the request. If the Component or activity that is consulted determines that the existence or nonexistence of the records is in itself classified, the requester shall be so notified by the DA activity originally receiving the request that it can neither confirm nor deny the existence of the record, and no referral shall take place.

SI.L2-3.14.1 · Flaw Remediation [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13 248
Potential Assessment Considerations · Is the time frame (e.g., a set number of days) within which system flaw identification activities (e.g., vulnerability scans, configuration scans, manual review) must be performed defined and documented [a]? · Are system flaws (e.g., vulnerabilities, misconfigurations) identified in accordance with the specified time frame [b]? · Is the time frame (e.g., a set number of days dependent on the assessed severity of a flaw) within which system flaws must be corrected defined and documented [e]? · Are system flaws (e.g., applied security patches, made configuration changes, or implemented workarounds or mitigations) corrected in accordance with the specified time frame [f]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.14.1 · FAR Clause 52.204-21 b.1.xii

A 2023 Government Accountability Office report on medical device cybersecurity described the importance of robust cybersecurity controls to ensure medical device safety and effectiveness because of the increasing integration of wireless, internet- and network-connected capabilities, and the electronic exchange of health information. [190] The FDA has also acknowledged, As electronic medical devices become increasingly connected to each other and to other technologies, the ability of connected systems to safely, securely and effectively exchange and use the information becomes critical. [. . .] Cybersecurity concerns rise along with the increasing medical device interoperability. [191] Accordingly, in 2023, the FDA issued updated guidance for industry and FDA staff on requirements for cybersecurity in medical devices. [192] And then there are digital health applications. When an application is deployed by a covered entity, an application developer may be a business associate and subject to the Security Rule. An application developer may also meet the HIPAA Rules' definition of health care provider. [193] and be a covered entity. [194] But also, individuals are increasingly interested in accessing their ePHI using applications and transmitting information collected by health and wellness applications to (printed page 912) their health care providers. [195] Such applications may empower individuals to better manage their health and participate in their health care and provide health care providers and researchers with a more holistic view of the individual's health at a particular point in time and over an extended period of time. [196] This technology, while valuable for understanding an individual's overall health, introduces another potential vulnerability to the security of ePHI and the information systems that create, receive, maintain, or transmit it. EHRs, networked medical devices, and applications are only the beginning. Artificial intelligence (AI) in health care, particularly for diagnosis and treatment, is in the nascent stages of development, but many are eager to test its promise. [197] After all, many experts believe that AI promises opportunities to improve patient care, outcomes, and population health, as well as to reduce costs. [198] The use of AI in health care is increasing and is expected to continue to increase. [199] A 2023 Healthcare Information and Management Systems Society (HIMSS) survey of health care cybersecurity professionals reported that approximately 50 percent of respondents' organizations permitted the use of generative AI technology. [200] And other new technologies are expected shortly, as discussed below. For example, according to reports, quantum computing may be available in the near future, which may have ramifications for data privacy and security. [201] We also know that researchers are exploring methods for storing ePHI in biological material (e.g., DNA). [202]

Under CMMC Level 2 (NIST SP 800-171 Rev 3), organizations must implement specific controls addressing this area. Key considerations include: 1. The specific NIST SP 800-171 controls that apply to this scenario 2. Documentation requirements for the SSP 3. Evidence needed for C3PAO assessment 4. Cost-effective implementation options for different organization sizes Organizations should reference the specific control families in NIST SP 800-171 Rev 3 and consult the CMMC Assessment Guide Level 2 for detailed assessment objectives. A Registered Practitioner (RP) can provide organization-specific guidance.

Identify reasonably anticipated threats. The list of threat events and threat sources should include reasonably anticipated and probable human and natural incidents that can negatively affect the

regulated entity's ability to protect ePHI. The information gathered for the technology asset inventory should be used to identify reasonably anticipated threats to ePHI. Identify potential vulnerabilities and predisposing conditions. For any of the various threats identified above to result in a significant risk, each needs a vulnerability or predisposing condition that can be exploited. While it is necessary to review threats and vulnerabilities as unique elements, they are often considered at the same time. Organizations should consider a given loss scenario and evaluate both, such as what threat sources might initiate which threat events or what vulnerabilities or predisposing conditions those threat sources might exploit to cause an adverse effect. From this, the regulated entity should develop a list of vulnerabilities (i.e., flaws or weaknesses) that could be exploited by potential threat sources. Determine the likelihood that a threat would exploit a vulnerability. For each threat event/threat source identified, a regulated entity should consider: the likelihood that the threat would occur and the likelihood that an occurred threat would exploit an identified vulnerability and result in an adverse effect. A regulated entity might consider assigning a likelihood value (e.g., ·very low,· ·low,· ·moderate,· ·high,· or ·very high·) to each threat/vulnerability pairing. As an example, the regulated entity may determine that the likelihood of a phishing attack occurring is very high and that the likelihood of the event exploiting a human vulnerability is moderate, resulting in an overall likelihood rating of high. Determine the impact of a threat exploiting a vulnerability. As with likelihood determination, a regulated entity may choose to express this effect in qualitative terms or use any other scale that the entity chooses. When selecting an impact rating, the regulated entity may consider how the threat event can affect the loss or degradation of the confidentiality, integrity, or availability of ePHI. Some tangible impacts can be measured quantitatively in terms of lost revenue, the cost of repairing the system, or the level of effort required to correct problems caused by a successful threat action. Other impacts cannot be measured in specific units (e.g., the loss of public confidence, the loss of credibility, or damage to an organization's interests), but they can be qualitatively described. Determine the level of risk to ePHI while considering the information gathered and determinations made during the previous steps. The level of risk is determined by analyzing the values assigned to the overall likelihood of threat occurrence and the resulting impact of threat occurrence.

cannot be used, contact the Regulatory Secretariat Division at 202-501-4755 or GSARegSec@gsa.gov . Please cite FAR Case 2023-008. SUPPLEMENTARY INFORMATION: The final FAR rule 2022-010, Establishing FAR part 40, amended the FAR to establish a framework for a new information security and supply chain security FAR part, FAR part 40. The final rule does not implement any of the information security and supply chain security policies or procedures; it simply established FAR part 40. The final FAR rule was published in the Federal Register at 89 FR 22604 , on April 1, 2024. Relocation of existing requirements and placement of new requirements into FAR part 40 will be done through separate rulemakings. Currently, the policies and procedures for prohibitions, exclusions, supply chain risk information sharing, and safeguarding information that address security objectives are dispersed across multiple parts of the FAR, which makes it difficult for the acquisition workforce and the general public to understand and implement applicable requirements. FAR part 40 will provide the acquisition team with a single, consolidated location in the FAR that addresses their role in implementing requirements related to managing information security and supply chain security when acquiring products and services. The new FAR part 40 provides a location to cover broad security requirements that apply across acquisitions. These security requirements include requirements designed to bolster national security through the management of existing or potential adversary-based supply chain risks across technological, intent-based, or economic means (e.g., cybersecurity (printed page 25269) supply chain risks, foreign-based risks, emerging technology risks). The intent is to structure FAR part 40 based on the objectives of the regulatory requirement (similar to how environmental objectives are covered in FAR part 23, and labor objectives are addressed in FAR part 22). Security-related requirements that include and go beyond information and communications technology (ICT) will be covered under FAR part 40. An example of products and services that include and go beyond ICT are cybersecurity supply chain risk management requirements such as requirements related to section 889 of the John S. McCain National Defense Authorization Act for Fiscal Year 2019 (Pub. L. 115-232). Security-related requirements that only apply to ICT acquisitions will continue to be covered in FAR part 39. The test for whether existing regulations would be in FAR part 40 would be based on the following questions: Question 1: Is the regulation or FAR case addressing security objectives? · If yes, move to question 2 · If no, the regulation would be located in another part of the FAR. Question 2: Is the scope of the requirements limited to ICT? · If yes, the regulation would be located in FAR part 39 · If no, the

regulation would be located FAR part 40.

the National Bureau of Standards. rity audit project, Mrs. Ruthberg worked closely with Mr. McKenzie on the planning, acted as the Workshop arrangements chairman, and is co- editor of these Proceedings. in computer science at NBS and most recently has become active in the managerial procedures required for computer security. Introduction Planning by Management Management Control ADP Security 2.4.1 2.4.2 2.4.3 2.4.4 2.4.5 INITIATING THE WORKSHOP PLANNING THE WORKSHOP 2.1 2.2 2.3 AT THE WORKSHOP THE SESSION REPORTS

and the per record cost of a breach involving personally identifiable information (across all industries) was \$183. [967] These costs include detection and investigation activities, notification activities, post-breach response activities, and activities attempting to minimize the loss of business. Thus, the benefits of the proposed rule would be to reduce the harms of health care breaches described in the preamble. The Department believes that implementing the changes in the NPRM would reduce both the incidence of breaches in health care and the costs of mitigating breaches when they occur. The Department also analyzed the potential cost savings of proposals that (printed page 1002) correspond to major factors affecting the costs of large breaches as identified in published reports. [968] The Department estimates that, at a minimum, performing the following actions would quantifiably reduce costs: (1) encryption; (2) penetration testing; (3) requiring MFA and notification of termination of access to ePHI; (4) increasing employee training; and (5) reducing noncompliance with regulations. These factors would account for an estimated 23.6 percent decrease in large breach costs. [969] For health care breaches, this corresponds to an estimated cost savings of \$2.6 million per large breach in high incidence years, and \$2.1 million per large breach in low incidence years. Non-Quantitative Analysis of Benefits A fundamental benefit of the proposed rule would be to decrease the effects of breaches on individuals who are the subjects of ePHI, namely patients and health plan members. Breaches of ePHI may cause harm to individuals in many ways, including loss of reputation and personal dignity and financial and medical fraud, which may result in false debts, impaired credit, and even health threats from misuse of health insurance credentials by another individual. ·[H]ealthcare data, which includes medical histories and personal identification, can last a lifetime. The information collected can be used for ransom, to commit tax frauds, to provide supporting disability documentation, to send fake bills to insurance providers, to obtain healthcare, prescription drugs, medical treatment, and to obtain government benefits like Medicare and Medicaid.· [970] Hackers can use stolen personal, medical, and financial data to take out a bank loan in the victim's name and change direct deposit information in payroll systems, allowing them to steal wages as well. [971] In addition, medical identity fraud can impact the victim's credit score and health insurance premiums, and may result in unexpected legal fees. [972]

n NIST IR 8319. For example, NIST IR 8319 explored whether the AES block cipher behaves as a 'pseudo-random permutation' (PRP), so that the block cipher modes of operation can rely on this assumption. NIST IR 8319 already mentioned that certain properties, such as the impact of the 128-bit block size of AES, will be analyzed for the modes of operation. This report will also analyze whether certain security requirements of AES implementations (e.g., resistance against side-channel attacks) are still true when they are used in a particular mode of operation or give an indication of new problems that may appear when modes of operation are used in an application. The failure of the security properties of the block cipher modes and their implementations leading to attacks will be investigated, with a particular focus on attacks that lead to practical insecurities that are listed in the NIST National Vulnerability Database (NVD), such as the Sweet32 attack [16] that is listed in the NVD as CVE-2016-2183 [67]. In order to avoid inadvertently overlooking security problems, internal NIST feedback and public comments will be taken into consideration. As such, this report has the intention of complementing rather than supplementing other reports on the NIST-recommended modes of operation, such as the report by Rogaway [74]. For historical reasons, not all NIST-recommended modes were designed according to a predefined list of security requirements. An attempt to retrospectively formalize a set of security requirements would be difficult. Instead, the question raised by Richard Barnes at Real

The designated ITPSO will ensure that contractor program personnel assigned insider threat program responsibilities and all other cleared employees complete training consistent with applicable CSA provided guidance. (1) The contractor will provide training to insider threat program personnel, including the contractor's designated ITPSO, on: (i) CI and security fundamentals. (ii) Procedures

for conducting insider threat response actions. (iii) Applicable laws and regulations regarding the gathering, integration, retention, safeguarding, and use of records and data, including the consequences of misuse of such information. (iv) Applicable legal, civil liberties, and privacy policies and requirements applicable to insider threat programs. (2) The contractor will provide insider threat awareness training to all cleared employees on an annual basis. Depending upon CSA specific guidance, a CSA may instead conduct such training. The contractor must provide all newly cleared employees with insider threat awareness training before granting access to classified information. Training will address current and potential threats in the work and personal environment and will include at a minimum: (i) The importance of detecting potential insider threats by cleared employees and reporting suspected activity to the insider threat program designee. (ii) Methodologies of adversaries to recruit trusted insiders and collect classified information, in particular within information systems. (iii) Indicators of insider threat behavior and procedures to report such behavior. (iv) CI and security reporting requirements, as applicable. (3) The contractor will establish procedures to validate all cleared employees who have completed the initial and annual insider threat training. (h) Derivative classification. (1) Initial training. The contractor will ensure all employees authorized to make derivative classification decisions are trained in the proper application of the derivative classification principles, in accordance with CSA direction. Employees are not authorized to conduct derivative classification until they receive such training. (2) Refresher training. In addition to the initial training, contractors will ensure all employees who conduct derivative classification receive training at least once every two years. Contractors will suspend an employee's derivative classification authority for any employee who does not receive such training at least once every two years. Training will emphasize the avoidance of over-classification and address: (i) Classification levels. (ii) Duration of classification. (iii) Identification and markings. (iv) Classification prohibitions and limitations. (v) Sanctions and classification challenges. (vi) Security classification guides. (vii) Information sharing. (3) Record of training. Contractors will retain records of the date of the most recent training (initial or refresher) and type of training provided to employees. (i) Information systems security.

This proposed rule does not create any new provisions or clauses. The rule updates language used in the clause text to clarify its intent and conform with current contract line item structure terminology. This rule does not change the applicability of the affected clause. IV. Executive Orders 12866 and 13563 E.O.s 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804. V. Executive Order 13771 This rule is not subject to E.O. 13771, because this rule is not a significant regulatory action under E.O. 12866. VI. Regulatory Flexibility Act DoD does not expect this proposed rule to have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601, et seq., because the rule is not creating any new requirements for contractors or changing any existing policies and practices. However, an initial regulatory flexibility analysis has been performed and is summarized as follows: The Department of Defense is proposing to amend the Defense Federal Acquisition Regulation Supplement (DFARS) to modify the text of DFARS clause 252.204-7002, Payment for Subline Items Not Separately Priced, to simplify and conform the clause text to current Government contract line item structure terminology, pursuant to action taken by the Regulatory Reform Task Force. The objective of this proposed rule is to clarify the intent of the clause for contractors, when submitting invoices under contracts that contain items that are not separately priced (NSP). The modification of these DFARS clauses implements a recommendation from the DoD Regulatory Reform Task Force. Based on an average of data for fiscal year 2016 through 2018 from the Federal Procurement Data System and Electronic Document Access, DoD awards annually approximately 12,435 contracts that include DFARS clause 252.204-7002 to 2,544 unique entities. Of the 12,435 awards, approximately 4,924 contracts (40 percent) are awarded to approximately 1,564 unique small business entities (60 percent). However, based on the available data and the objective of the rule, DoD does not anticipate that this proposed rule will significantly impact small business entities. This proposed rule does not include any new reporting, recordkeeping, or other compliance requirements for small businesses.

(Response) FDA acknowledges that, currently, the transporter may have limited knowledge of the contents of the packages that it carries and that an undue records retention burden would result if the default would be the longer retention period. FDA notes, however, that under this final rule transporters must know that they are transporting food and be able to record a description of that food. Nonetheless, FDA has relaxed the records retention requirement for transporters from the proposed rule to this final rule. Transporters, or nontransporters retaining records on behalf of a transporter, are required to retain records for 6 months for any food having a significant risk of spoilage, loss of value, or loss of palatability within 60 days after the date the food is received or released and 1 year for any food having a significant risk of spoilage, loss of value, or loss of palatability only after a minimum of 60 days after the date the food is received or released. FDA also has codified in this final rule an option for transporters to comply with recordkeeping requirements of this final rule by keeping records already required by the existing bill of lading requirements applicable to interstate transporters. (Comment 207) One comment expresses concern that differing knowledge of the contents of food packages between transporters and nontransporters would require standards of information exchange to be created to coordinate the contents of records maintained by the two types of entities. The comment suggests that without such standards, the coordination costs may be high, because certain records maintained by nontransporters would need to be exchanged with transporters for them to have the full knowledge of the contents and extent of the packaging. Failure to create these standards would result in elevated costs for transporters. (Response) FDA acknowledges the limited knowledge that transporters currently may have about the contents of the packages that they carry. FDA has included less detailed information requirements in the final rule to respond to these comments; however, FDA believes the information it is requiring is necessary to allow the FDA to conduct a tracing investigation efficiently and effectively. In addition, FDA included an option whereby transporters can fulfill their recordkeeping requirements by keeping records already required for interstate transporters. Furthermore, the final rule provides an option allowing transporters to enter into a contractual arrangement with the non-transporter immediate previous source located in the United States or with the non-transporter immediate subsequent recipient located in the United States; any contractual arrangements would redistribute the burden of establishing and maintaining transportation records between transporters and non-transporters but would not change the total recordkeeping costs since the same number of records would be established (printed page 71639)

means any information, document, media, or machine-readable material regardless of physical form or characteristics that is created or obtained by a contractor through the storage, processing, or communication of Government data. Government-related data does not include: (1) A contractor's business records (e.g., financial records, legal records) that do not incorporate Government data, or (2) Data such as operating procedures, software coding or algorithms that are not primarily applied to the Government data. High value asset means Government data or a Federal information system that is designated as a high value asset pursuant to OMB Memorandum M-19-03, Strengthening the Cybersecurity of Federal Agencies by enhancing the High Value Asset Program. Media means physical devices or writing surfaces including, but not limited to, magnetic tapes, optical disks, magnetic disks, large-scale integration memory chips, and printouts onto which information is recorded, stored, or printed within an information system (NIST SP 800-37). Metadata means information describing the characteristics of data including, but not limited to, structural metadata that describes data structures (e.g., data format, syntax, and semantics) and descriptive metadata that describes data contents (e.g., information security labels) (NIST SP 800-53). Service account means an account used by machines, e.g., an operating system, application, process, or service, not used by a human. 39.X02 Procedures. All FIS require protection as part of good risk management practices. A contract for services to develop, implement, operate, or maintain a FIS may require contractors to utilize cloud computing services, computing services other than cloud computing services (i.e., non-cloud computing services), or both service approaches in performing the contract. Each service approach requires certain compliances and standards to be met to ensure appropriate FIS protection. 39.X02-1 Federal information systems using non-cloud computing services. (a) Contracting officer verification. (1) Requirement criteria. When acquiring services to develop, implement, operate, or maintain a FIS using non-cloud computing services, the contracting officer shall verify with the requiring activity that the requirement: (i) Categorizes the FIS based on an impact analysis of the information processed, stored, and transmitted by the system (see the current version of Federal Information Processing Standards (FIPS) Publication 199, Standards for Security Categorization of Federal Information and

Information Systems, for additional information); (ii) Identifies a set of controls to protect the FIS based on an assessment of risk in accordance with- (A) The current version of FIPS Publication 200, Minimum Security Requirements for Federal Information and Information Systems;

In terms of security configurations, organizations should use sound host hardening principles. For example, organizations should follow the principle of least privilege, which refers to configuring hosts to provide only the minimum necessary rights to the appropriate users, processes, and hosts. Least privilege can be helpful in preventing malware incidents, because malware often requires administrator-level privileges to exploit vulnerabilities successfully. If an incident does occur, prior application of least privilege might minimize the amount of damage that the malware can cause. Organizations should also implement other host hardening measures that can further reduce the possibility of malware incidents, such as the following: and what data sources might record the information. For example, a host's current IP address is typically needed for remote actions; of course, a host's physical location is needed for local actions. One piece of information can often be used to determine others, such as mapping an IP address to a media access control (MAC) address, which could then be mapped to a switch serving a particular group of offices. If an IP address can be mapped to a host owner or user-for example, by recording the mapping during network login-the owner or user can be contacted to provide the host's location. The difficulty in identifying the physical location of an infected host depends on several factors. In a managed environment, identifying a host's location is often relatively easy because of the standardized manner in which things are done. For example, host names might contain the user's ID or office number, or the host's serial number (which can be tied to a user ID). Also, asset inventory management tools might contain current information on host characteristics. In other environments, especially those in which users have full control over their hosts and network management is not centralized, it might be challenging to link a machine to a location.

While these guidelines are primarily designed for federal users and system administrators to adequately protect sensitive but unclassified U.S. Federal Government data against serious threats on the Internet, they may also be used within closed network environments to segregate data. (The client-server model and security services discussed also apply in these situations). This Special Publication supersedes NIST Special Publication 800-52 Revision 1. This Special Publication should be used in conjunction with existing policies and procedures. TLS 1.3, specified in RFC 8446 [57], represents a significant change to TLS that aims to address threats that have arisen over the years. Among the changes are a new handshake protocol, a new key derivation process that uses the HMAC-based Extract-and-Expand Key Derivation Function (HKDF) [37], and the removal of cipher suites that use RSA key transport or static Diffie-Hellman (DH) key exchanges, the CBC mode of operation, or SHA-1. Many extensions defined for use with TLS 1.2 and previous versions cannot be used with TLS 1.3. Security is not a single property that is (or is not) possessed by a protocol. Rather, security includes a complex set of related properties that together provide the required information assurance characteristics and information protection services. Security requirements are usually derived from a risk assessment of the threats or attacks that an adversary is likely to mount against a system. The adversary is likely to take advantage of implementation vulnerabilities found in many system components, including computer operating systems, application software systems, and the computer networks that interconnect them. Thus, in order to secure a system against a myriad of threats, security must be judiciously placed in the various systems and network layers.

, October 21, 2016 implemented the DoD's requirement that contractors shall implement NIST SP 800-171 as soon as practical, but not later than December 31, 2017. Public comments related to costs for implementation were published with that final rule, along with DoD's responses. CMMC cost estimates are derived estimates based on internal expertise and public feedback in accordance with OMB Circular A-4 and are representative of average assessment efforts not actual prices of C3PAO services available in the marketplace. Market forces of supply and demand will determine C3PAO pricing for CMMC Level 2 certification assessments and how C3PAOs choose to distinguish their service offerings from other C3PAOs, including the timely availability of an assessment team, or re-assessments after an assessment failure. The size and complexity of the network within the scope of the assessment impacts the costs as well. The DoD declines to speculate about how OSCs and C3PAOs negotiate mutually (printed page 83153) acceptable terms and conditions for assessment agreements. OSA implementation of the requirements of FAR clause 52.204-21 and DFARS clause 252.204-7012 long predate CMMC and are not included in CMMC cost estimates, since those requirements are not driven by or attributable to CMMC, even for new or aspiring defense contractors, and have

been in force since 2017 on DoD contracts that include the processing, storing, or transmitting of FCI or CUI in the performance of a DoD contract. The DoD has taken measures to make a self-assessment as straight forward as possible and provided guidance to mitigate any variance in assessment scores. Additionally, the DoD has streamlined CMMC requirements to align directly to NIST guidelines and has eliminated unique security practices to ease the burden on smaller companies. DoD must enforce CMMC requirements uniformly across the Defense Industrial Base for all contractors and subcontractors who process, store, or transmit CUI. Creation of a grants and assistance programs are beyond the scope of this rule. DFARS clause 252.204-7012 requires protection of security protection assets and security protection data. Section 1.1 of NIST SP 800-171 R2 states: "The requirements apply only to components of nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components." There is therefore no increase in the scope as described in the rule. Security protection data requires protection commensurate with the CUI it protects and is based on how and where the security protection data is stored. The FedRAMP requirements for handling security protection data is therefore the same as that for handling CUI. Any impact to the cost of serving Government customers across the DoD is beyond the scope of this rule.

) for the current version of this collection. A contract security classification specification with its attachments, supplements, and incorporated references, provides security classification guidance (lists the applicable security classification guides for a contractor to use) to a contractor in connection with a classified contract. It is designed to identify the classified areas of information involved in the classified effort and, particularly, to identify the specific items of information within these areas that require protection. This rule provides NISP contractors security requirements which align to 32 CFR part 2001, in a manner equivalent to the protection of classified information within the executive branch of the USG. If a GCA determines that additional safeguards are essential in specific contracts, the GCA can impose more operational security provisions above the requirements of this rule. The GCA can also determine that additional physical or technical security requirements are needed in a contract above the requirements of this rule. Even though the contract security classification is contract-specific, it is not always all-inclusive. Additional security requirements are sometimes included in other parts of a contract. All related materials for approved information collection are available at:

<https://www.reginfo.gov/public/do/PRAMain>. In addition, specific locations for finalized collection instruments, to include the designated OMB Control Number is included where information collections are cited in this rule. In addition, depending upon the CSA with security cognizance, an entity's legal headquarters may need to implement additional information collections, such as: DD Form 441, "DoD Security Agreement" for DoD is an agreement between DCSA and the cleared legal entity for the entity to comply with the NISPOM security requirements, to be subject to inspections and to allow for a 30 day notice by the entity or DCSA to terminate the agreement (e.g., if there is no longer a valid USG requirement for access to classified information (available at https://www.esd.whs.mil/Portals/54/Documents/DD/forms/dd/dd0441_2020.pdf); NRC Form 441, "Security Agreement" for NRC, the provisions of the NRC Form 441 are similar to those included in the DD Form 441 (available at <https://www.nrc.gov/reading-rm/doc-collections/forms/nrc441info.html>). DOE does not have a separate Form 441, but instead, binds the contractor to the FCL (and security requirements) via the contract, along with meeting all other requirements in this rule. As part of FCL processing, an entity must complete a Standard Form (SF) 328, "Certificate Pertaining to Foreign Interest," OMB Control number 0704-0579, (available at <https://www.gsa.gov/forms-library/certificate-pertaining-foreign-interests>),

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Planning 3.15.2 System Security Plan a. Develop a system security plan that: 1. Defines the constituent system components; 2. Identifies the information types processed, stored, and transmitted by the system; 3. Describes specific threats to the system that are of concern to the organization; 4. Describes the operational environment for the system and any dependencies on or connections to other systems or system components; 5. Provides an overview of the security requirements for the system; 6. Describes the safeguards in place or planned for meeting the security requirements; 7. Identifies individuals that fulfill system roles and responsibilities; and 8. Includes other relevant information necessary for the protection of CUI. b. Review and update the system security plan [Ass

The National Institute of Standards and Technology (NIST) hosted an in-person, all-day workshop on February 27, 2024, to discuss existing and emerging cybersecurity threats and mitigation techniques for semiconductors throughout their life cycle. The workshop obtained valuable feedback from

industry, academia, and government to inform NIST's development of cybersecurity and supply chain standards, guidance, and recommended practices. The discussion focused on semiconductor development and highlighted cybersecurity measurements and metrics that utilize reference data sets to facilitate the testing, attestation, certification, verification, and validation of semiconductor components. It also emphasized the use of automated cybersecurity tools and techniques to secure manufacturing environments throughout the development life cycle. This report summarizes the content that was presented and discussed at the workshop. These activities range from physical protection mechanisms (e.g., tamper-resistant packaging) to strong encryption protocols to safeguard data. Secure boot processes ensure that only verified firmware runs, and maintaining supply chain integrity through verification and audits prevents counterfeit components. Life cycle management includes secure provisioning, updates, and end-of-life processes that are complemented by rigorous security testing and compliance with regulatory standards. Educating users on secure practices and continuously improving security measures further fortifies defenses against evolving threats and ensures that semiconductor devices operate securely throughout their life cycle. The last panel member was Matthew Areno, Senior Principal Engineer for Intel Corporation. Matthew admitted that there is no industry standard to describe the phases of the supply chain for ICs.

Appendix B to Part 505 Denial Authorities for Records Under Their Authority (Formerly Access and Amendment Refusal Authorities) (a) The Administrative Assistant to the Secretary of the Army is authorized to act for the Secretary of the Army on requests for all records maintained by the Office of the Secretary of the Army and its serviced activities, as well as requests requiring the personal attention of the Secretary of the Army. This also includes civilian Equal Employment Opportunity (EEO) actions. (See DCS, G-1 for Military Equal Opportunity (EO) actions.) The Administrative Assistant to the Secretary of the Army has delegated this authority to the Chief Attorney, OAASA (See DCS, G1 for Military Equal Opportunity (EO) actions). (b) The Assistant Secretary of the Army (Financial Management and Comptroller) is authorized to act on requests for finance and accounting records. Requests for CONUS finance and accounting records should be referred to the Defense Finance and Accounting Service (DFAS). The Chief Attorney, OAASA, acts on requests for non-finance and accounting records of the Assistant Secretary of the Army (Financial Management and Comptroller). (c) The Assistant Secretary of the Army (Acquisition, Logistics, & Technology) is authorized to act on requests for procurement records other than those under the purview of the Chief of Engineers and the Commander, U.S. Army Materiel Command. The Chief Attorney, OAASA, acts on requests for non-procurement records of the Assistant Secretary of the Army (Acquisition, Logistics and Technology). (d) The Deputy Assistant Secretary of the Army (Civilian Personnel Policy)/Director of Civilian Personnel, Office of the Assistant Secretary of the Army (Manpower and Reserve Affairs) is authorized to act on requests for civilian personnel records, personnel administration and other civilian personnel matters, except for EEO (civilian) matters which will be acted on by the Administrative Assistant to the Secretary of the Army. The Deputy Assistant Secretary of the Army (Civilian Personnel Policy)/Director of Civilian Personnel has delegated this authority to the Chief, Policy and Program Development Division (Note: Requests from former civilian employees to amend a record in an Office of Personnel Management system of records, such as the Official Personnel Folder, should be sent to the Office of Personnel Management, Assistant Director for Workforce Information, Compliance, and Investigations Group: 1900 E. Street, NW., Washington, DC 20415-0001). (e) The Chief Information Officer G-6 is authorized to act on requests for records pertaining to Army Information Technology, command, control communications and computer systems and the Information Resources Management Program (automation, telecommunications, visual information, records management, publications and printing). (f) The Inspector General is authorized to act on requests for all Inspector General Records.

3.2.4 Effects on Magnitude(s) of Impact of Threats... 3.2.4 Effects on Magnitude(s) of Impact of Threats ## How does the IoT device affect magnitude(s) of impact considered as part of a risk assessment? In addition to likelihood of occurrence, a risk assessment will consider the magnitude of impact.

Similar uses of generative AI by regulated entities, including the training of AI models on patient data, could result in impermissible uses and disclosures, including exposure to bad actors that can exploit the information. [909] As part of its risk analysis and risk management activities, a regulated entity must consider the risk associated with different uses and data. [910] Accordingly, we expect that a regulated entity interested in using AI would include the use of such tools in its risk analyses and associated risk management activities. The regulated entity's risk

analysis must include consideration of, among other things, the type and amount of ePHI accessed by the AI tool, to whom the data is disclosed, and to whom the output is provided. The NIST AI Risk Management Framework is a helpful resource for regulated entities to better (printed page 991) understand, measure, and manage risks, effects, and harms of AI. [911] The Security Rule requires a regulated entity to conduct repeated risk analyses that consider any changes to its environment or operations, such as updates or changes in technology or clinical administration, and to apply all reasonable updated protections to safeguard ePHI. [912] Accordingly, as technology such as AI evolves, the Department would expect a regulated entity to perform a risk analysis to consider the effects of such changes on the confidentiality, integrity, and availability of ePHI. As NCVHS observed, "[I]t is important to conduct risk analyses on AI throughout the life cycle of the system." [913] We believe the proposals in this NPRM would clarify our expectations for when and how regulated entities need to consider, prepare for, and address such changes. For example, the Department proposes to expressly require that a regulated entity develop a written inventory of its technology assets. Under this proposal, the Department would expect that AI software used to create, receive, maintain, or transmit ePHI or that interacts with ePHI, including where ePHI is used to train the AI software, would be listed as part of its technology asset inventory, which feeds into the regulated entity's risk analysis. Making AI safe and secure with respect to ePHI requires efforts in a variety of areas: biotechnology, cybersecurity, critical infrastructure to address risks. [914] The Federal Government seeks to ensure that the collection, use, and retention of ePHI is lawful and secure, and that it mitigates privacy and confidentiality risks. Across the administration, Federal agencies are considering potential uses for AI, as well as their benefits and risks, consistent with E.O. 11410 and its principles to advance and govern the development and use of AI. [915]

A director (MGMT5) for 16 hours ($\$190.52/\text{hr} \times 16\text{hrs} = \$3,048$) An external service provider (ESP) for 48 hours ($\$260.28/\text{hr} \times 48\text{hrs} = \$12,493$) Phase 3: Reporting of assessment results: \$2,851 A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) An external service provider (ESP) for 8 hours ($\$260.28/\text{hr} \times 8\text{hrs} = \$2,082$) A staff IT specialist (IT4-SB) for 0.08 hours ($\$86.24/\text{hr} \times 0.08\text{hrs} = \7) Affirmation initial affirmation post assessment: \$1,459 Reaffirmations: It is estimated that the costs to reaffirm a CMMC Level 2 Self-Assessment annually is \$1,459 (three-year costs to reaffirm a CMMC Level 2 Self-Assessment annually is \$4,377, or $\$1,459 \times 3$): A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) A staff IT specialist (IT4-SB) for 8.08 hours ($\$86.24/\text{hr} \times 8.08\text{hrs} = \697) The Level 2 Self-Assessment and Affirmations cost burden will be addressed as part of the 48 CFR acquisition rule. Summary: The following is the annual small entities total cost summary for CMMC Level 2 Self-Assessments and Affirmations over a ten-year period: (Example calculation, Year 2: ($\$34,277$ self-assessment per entity $\times 101$ entities) + ($\$1,459$ annual affirmation per entity $\times 20$ entities) = $\$3,491,193$). (printed page 89109) CMMC Level 2 Certification and Affirmation Costs for Small Business Entities The costs account for a CMMC Level 2 Certification assessment and affirmation costs of the applicable contractor information system(s) with NIST SP 800-171 Rev 2 requirements based on the assumptions defined. CMMC Level 2 certification assessments require hiring a C3PAO to perform the assessment. Nonrecurring or recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with CMMC Level 2 C3PAO Certification since it is assumed the contractor has implemented NIST SP 800-171 Rev 2 requirements. Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 2 C3PAO Certification and affirmation for a small entity is $\$101,752$. The three-year cost is $\$104,670$ (as summarized in section 3(b), Table 1), and includes the triennial assessment + affirmation plus two additional annual affirmations ($\$101,752 + \$1,459 + \$1,459$). Phase 1: Planning and preparing for the assessment: \$20,699 A director (MGMT5) for 54 hours ($\$190.52/\text{hr} \times 54\text{hrs} = \$10,288$) An external service provider (ESP) for 40 hours ($\$260.28/\text{hr} \times 40\text{hrs} = \$10,411$) Phase 2: Conducting the C3PAO assessment: \$45,509 A director (MGMT5) for 64 hours ($\$190.52/\text{hr} \times 64\text{hrs} = \$12,193$) An external service provider (ESP) for 128 hours ($\$260.28/\text{hr} \times 128\text{hrs} = \$33,316$) Phase 3: Reporting of C3PAO Assessment Results: \$2,851 A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) An external service provider (ESP) for 8 hours ($\$260.28/\text{hr} \times 8\text{hrs} = \$2,082$) A staff IT specialist (IT4-SB) for 0.08 hours ($\$86.24/\text{hr} \times 0.08\text{hrs} = \7) Affirmation initial affirmation post assessment: \$1,459 C3PAO Costs:

The National Bureau of Standards, with the support of the U.S. General Accounting Office, sponsored an invitational workshop on "Audit and Evaluation of Computer Security," held in Miami Beach, Florida on March 22-24, 1977. area and define appropriate subjects for future research. parts in the audit and computer communities were invited to discuss the subject in one of ten sessions,

each of which considered a different aspect. These reports form the body of these Proceedings. The ten topics reported on are: Internal Audit Standards, Qualifications and Training, Security Administration, Audit Considerations in Various System Environments, Administrative and Physical Controls, Program Integrity, Data Integrity, Communications, Post-Processing Audit Tools and Techniques, and Interactive Audit Tools and Techniques. KEYWORDS: training, communications security, computer controls, computer security, data integrity, interactive audit, internal audit, post-processing audit, program integrity. Internal Audit Standards Qualifications and Training Security Administration Audit Considerations in Various System Environments Administrative and Physical Controls Program Integrity Data Integrity Communications Post-Processing Audit Tools and Techniques Interactive Audit Tools and Techniques

(Public address by Dr. Jakob Kellenberger, President, International Committee of the Red Cross, 11 September 2009.) Again, contracting regulations are not the place to define terms that are not yet defined under international law. The Rule specifies that command rules for the use of force will be consistent with Chairman of the Joint Chiefs of Staff Instruction 3121.01B. This will provide commonality regarding the Rules for the Use of Force (RUF) but with the flexibility for commands to interpret it in accordance with local, and sometimes transitory, circumstances. Comment: The Rule may benefit from additional guidance on inter-agency cooperation Response: Interagency coordination is essential to successful contingency planning. The Rule, as written supports flexible, agile, and focused contingency planning and DoD, DoS and USAID believe the rule provides sufficient strategic direction for interagency coordination relative to PSC oversight and conduct. DoD disagrees with the respondent's assertion that many coordination issues will be common across AORs. Some may, many more may not. The flexibility to adapt procedures to local circumstances is essential. As the same respondent notes in this same section, guidance and procedures in the Iraq Memorandum of Agreement (MOA) are not easily transferrable to contingency operations outside of Iraq. The MOA between DoD and DoS in place in Iraq has proven to be extremely successful and serves as a good example of interagency coordination. It was referenced in the IFR as an example or point of departure for developing GCC guidance and procedures. However, to avoid confusion, in the Final Rule we have removed the last sentence in Section 159.6(d) which references the MOA. DoD, DoS and USAID recognize that some PSC or PSC personnel activities may require coordination with other Federal agency partners who contract for private security services. Comment: Confusion about Geographic Combatant Commander Delegation Authority to Subordinate Commander Response: Geographic combatant commands themselves do not follow a uniform organizational structure and commanders are free to assign different responsibilities to the most appropriate components of their staffs. The language in the Final Rule has been changed to provide more specificity as to the subordinate level to which GCCs can delegate responsibility for implementation. Through the Rule, the phrase 'Subordinate Commander' has been replaced with 'sub unified commanders or combined/joint task force commanders'. Comment: The rule needs to include reference to existing powers of removal of a PSC and personnel Response:

(C) To effect recovery of improper payments or delinquent debts from current or former beneficiaries. (3) The comparison of records must be computerized. Manual comparisons are not covered. (4) Any activity that expects to participate in a Computer Matching Program must contact the DA FOIA/P Office immediately. (5) In all cases, Computer Matching Agreements are processed by the Defense Privacy Office and approved by the Defense Data Integrity Board. Agreements will be conducted in accordance with the requirements of 5 U.S.C. 552a, and OMB Circular A-130. (b) Other matching. Several types of computer matching are exempt from the restrictions of the Act such as matches used for statistics, pilot programs, law enforcement, tax administration, routine administration, background checks, and foreign counterintelligence. The DA FOIA/P Office should be consulted if there is a question as to whether the Act governs a specific type of computer matching. §505.14 Recordkeeping requirements under the Privacy Act. (a) AR 25-400-2, The Army Records Information Management System (ARIMS). To maintain privacy records are required by the Army Records Information Management System (ARIMS) to provide adequate and proper documentation of the conduct of Army business so that the rights and interests of individuals and the Federal Government are protected. (b) A full description of the records prescribed by this part and their disposition/retention requirements are found on the ARIMS Web site at <https://www.arims.army.mil>. Appendix A to Part 505-References (a) The Privacy Act of 1974 (5 U.S.C. 552a, as amended). (b) OMB Circular No. A-130, Management of Federal Information Resources. (c) AR 25-55, The Department of the Army Freedom of Information Program. (printed page 46066) (d) DA PAM 25-51, The Army

Privacy Program-System of Records Notices and Exemption Rules. (e) DOD Directive 5400.11, Department of Defense Privacy Program. (f) DOD 5400.11-R, Department of Defense Privacy Program. (g) AR 25-2, Information Assurance (h) AR 25-400-2, The Army Records Information Management System (ARIMS). (i) AR 27-10, Military Justice. (j) AR 40-66, Medical Record Administration and Health Care Documentation. (k) AR 60-20 and AFR 147-14, Army and Air Force Exchange Service Operating Policies. (l) AR 190-45, Law Enforcement Reporting. (m) AR 195-2, Criminal Investigation Activities. (n) AR 380-5, Department of Army Information Security Program. (o) DOD Directive 5400-7, DOD Freedom of Information Act (FOIA) Program. (q) DOD 5400.7-R, DOD Freedom of Information Program. (r) DOD 6025.18-R, DOD Health Information Privacy Regulation (HIPAA). (s) U.S. Department of Justice, Freedom of Information Act Guide and Privacy Act Overview. (t) Office of Secretary of Defense memorandum, dated July 15, 2005, subject: Notifying Individuals when Personal Information is Lost, Stolen, or Compromised located at <http://www.army.mil/ciog6/referencs/policy/dos/OSDprivateinfo.pdf> .

3.3.5 Remote Computing Security controls in a remote computing or inter- active environment are important because physical locks and keys alone may not provide for adequate accountability The minimum controls to be or deter unauthorized access.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 236 [DOD-2009-OS-0183/RIN 0790-AI60] AGENCY: Office of the DoD Chief Information Officer, DoD. ACTION: Interim final rule. SUMMARY: DoD is publishing an interim final rule to establish a voluntary cyber security information sharing program between DoD and eligible DIB companies. The program enhances and supplements DIB participants' capabilities to safeguard DoD information that resides on, or transits, DIB unclassified information systems. DATES: This rule is effective May 11, 2012. Comments must be received by July 10, 2012. ADDRESSES: You may submit comments, identified by docket number and/or RIN number and title, by any of the following methods: Federal Rulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. Mail: Federal Docket Management System Office, 4800 Mark Center Drive, East Tower, Suite 02G09, Alexandria, VA 22350-3100. Instructions: All submissions received must include the agency name and docket number or Regulatory Information Number (RIN) for this Federal Register document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing on the Internet at <http://www.regulations.gov> as they are received without change, including any personal identifiers or contact information. FOR FURTHER INFORMATION CONTACT: DIB Cyber Security and Information Assurance Program Office: (703) 604-3167, toll free (855) 363-4227, email DIB.CS/IA.Reg@osd.mil . SUPPLEMENTARY INFORMATION: Background Cyber threats to DIB unclassified information systems represent an unacceptable risk of compromise of DoD information and pose an imminent threat to U.S. national security and economic security interests. DoD's voluntary DIB CS/IA program enhances and supplements DIB participants' capabilities to safeguard DoD information that resides on, or transits, DIB unclassified information systems. This rule is being published as an interim final rule to: (a) Allow eligible DIB companies to receive USG threat information and share information about network intrusions that could compromise critical DOD programs and missions. (b) Permit DIB companies and DOD to assess and reduce damage to critical DOD programs and missions when DOD information is compromised. (c) Fulfill statutory requirements to ensure the protection of DOD information.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in Federal information systems. - Physical Security - the protection of property, e.g. using fences and locks; - Personnel Security - e.g. using background checks; - Contingency Planning and Disaster Recovery - how to resume normal operations after an incident, also known as Business Continuity Planning; - Operational Security -

protecting business plans and processes, and - Privacy - protecting personal information. 2 Lacking any one of these components diminishes the effectiveness of the others. For example, good physical security measures mean little if the personnel you hire intend to harm your business (poor personnel security). Or, strong privacy policies can depend on cybersecurity practices that protect customer information that is electronically stored.

In the application deployment model, the integrity of sensitive data residing within the data owner's domain must be protected. Protection mechanisms for application data include data - [11] Rushby J (1992) Noninterference, transitivity, and channel-control security policies. (SRI International, Menlo Park, CA), Technical Report CSL-92-02. Available at <http://www.csl.sri.com/papers/csl-92-2/> - [12] Change ATC, Foster JL, Hall DK (1987) Nimbus-7 SMMR derived global snow cover parameters. *Annals of Glaciology* 9:39-44. <https://doi.org/10.3189/S0260305500200736> - [13] Nurmi D, Wolski R, Grzegorzczak C, Obertelli G, Soman S, Youseff L, Zagorodnov D (2009) The Eucalyptus open-source cloud-computing system. 9th IEEE/ACM International Symposium on Cluster Computing and the Grid (CCGRID'09) (IEEE, Shanghai, China), pp 124-131. <https://doi.org/10.1109/CCGRID.2009.93> - [14] Sefraoui O, Aissaoui M, Eleuldi M (2012) OpenStack: toward an open-source solution for cloud computing. *International Journal of Computer Applications* 55(3):38-42. <https://doi.org/10.5120/8738-2991> - [15] Scarfone KA, Souppaya MP, Hoffman P (2011) Guide to Security for Full Virtualization Technologies. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-125. <https://doi.org/10.6028/NIST.SP.800-125> - [16] Wang Z, Jiang X (2010) Hypersafe: A lightweight approach to provide lifetime hypervisor control-flow integrity. 2010 IEEE Symposium on Security and Privacy (SP) (IEEE, Berkeley/Oakland, CA), pp 380-395. <https://doi.org/10.1109/SP.2010.30> - [17] Berger S, Cáceres R, Pendarakis D, Sailer R, Valdez E, Perez R, Schildhauer W, Srinivasan D (2008) TVDc: managing security in the trusted virtual datacenter. *ACM SIGOPS Operating Systems Review* 42(1):40-47.

338] Since 2013, the role technology plays in the storage and transmission of information has changed, as have the types of media used to store and transmit such information. For example, traditional landlines [339] are rapidly being replaced with electronic communication technologies, such as Voice over internet Protocol (VoIP), [340] and mobile technologies that use electronic media, such as the internet, intra- and extranets, cellular, and Wi-Fi. [341] Some current electronic technologies that regulated entities use for remote communications may include communication applications on a smartphone or another computing device, VoIP technologies, technologies that electronically record or transcribe a telehealth session, and messaging services that electronically store audio messages. The definition of electronic media does not account for these changes because it excepts (printed page 922) transmissions via fax, and of voice, via telephone, from transmissions via electronic media, nor does the definition take into consideration new and emerging technologies. Accordingly, the Department believes that it is appropriate to reconsider this definition. 3. Proposals The Department proposes to modify the definition of 'electronic media' as follows. First, the Department proposes to revise paragraph (1) of the definition to clarify that electronic media includes not only media on which data may be recorded, but also media on which data may be maintained or processed. Generally, data is either at rest, in transit, or in process (e.g., being worked on, in use, being modified in memory, or being updated). [342] After the data is no longer in use, it is either maintained or transmitted. It is especially important for entities to protect data in process because generally, data must be unencrypted to be processed, making this a time when it is particularly vulnerable to a breach or other security incident. [343] To that end, the Department's proposal would clarify that the definition includes electronic media that is used to record, maintain, or process data. The Department also proposes to revise paragraph (1) to clarify and update terminology used in a non-exhaustive list of examples of electronic storage material. Additionally, to ensure that the definition includes future technology, the Department proposes to add to the list of examples 'any other form of digital memory or storage' on which data may be recorded, maintained, or processed. As discussed above, traditional landlines and fax machines are rapidly being replaced with electronic communication technologies and mobile technologies that use electronic media. The Security Rule applies when a regulated entity uses such electronic communication technologies. Therefore, regulated entities using telephone systems and fax equipment that transmit ePHI need to apply the Security Rule safeguards to those technologies. [344]

CIS Safeguard 7.2 · Establish and Maintain a Remediation Process Establish and maintain a risk-

based remediation strategy documented in a remediation process, with monthly, or more frequent, reviews. Implementation Groups: 1,2,3 Asset Type: applications Security Function: respond Parent Control: Continuous Vulnerability Management

During the staffing and coordination of actions to, from, and within components in conduct of daily business, exempt materials from other systems of records may in turn become part of the case record in this document control system. To the extent that copies of exempt records from those other systems of records are entered into this system, the Office of the Secretary of Defense hereby claims the same exemptions for the records from those other systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a (j)(2) and (k)(1) through (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a. (c) Specific exemptions: All systems of records maintained by any OSD Component shall be exempt from the requirements of 5 U.S.C. 552a(d) pursuant to subsection (k)(1) of that section to the extent that the system contains any information properly classified under Executive Order 11265, 'National Security Information,' dated June 28, 1952, pursuant to subsection (k)(1) of that section to the extent that the system contains any information properly classified under E.O. 11265, 'National Security Information,' dated June 28, 1979, as amended, and required by the Executive Order to be kept classified in the interest of national defense or foreign policy. This exemption, which may be applicable to parts of all systems of records, is necessary because certain record systems not otherwise specifically designated for exemptions may contain isolated information which has been properly classified. The Secretary of Defense has designated the following OSD system of records described below specifically exempted from the appropriate provisions of the Privacy Act pursuant to the designated authority contained therein: (1) System identifier and name. DGC 16, Political Appointment Vetting Files. (i) Exemption.

To address the minor inconsistencies between the definitions of the safeguards and to ensure that each safeguard is afforded an equal weight of importance, the Department proposes similar but minor changes across the definitions. The Department proposes to add the word 'related' to the definition here, and below to add the words 'and related' when necessary, to more clearly connect the components that make up safeguards. In the case of administrative safeguards, the Department's proposal relates administrative actions to administrative policies and procedures. The Department believes that this change would reduce confusion and improve clarity about compliance obligations. We are proposing a similar change to the definitions of physical safeguards and technical safeguards below. Additionally, we are proposing to clarify that maintenance includes updating and modifying with respect to administrative safeguards. 3. Clarifying the Definition of 'Authentication' a. Current Provision and Issues To Address The Security Rule defines authentication as corroboration that a person is the one claimed. By limiting the definition of authentication to persons, the current definition neglects to acknowledge the importance to the security of ePHI of authenticating technology assets that are components of a regulated entity's electronic information systems that create, receive, maintain, or transmit ePHI or that otherwise affect the confidentiality, integrity, or availability of ePHI, or that the regulated entity intends to connect to such electronic information systems. [352] Absent such authentication, a bad actor could add technology assets (e.g., software) to a regulated entity's electronic information systems that enable the bad actor to compromise the security of ePHI. b. Proposal To modernize the definition of authentication to reflect best practices in cybersecurity today, the Department proposes to clarify the definition to mean corroboration that either a person or technology asset is the one they are claiming to be. The modified definition would also improve readability with minor changes in wording. The Department believes as proposed, the revised definition would more accurately reflect the role played by technology assets in electronic information systems today. For example, a covered health care

provider permits individuals to access their own PHI using an application that connects to the software that runs the covered health care provider's patient portal. Not only must the individual be authenticated as a user, but the application must be authenticated such that the covered entity's software can verify that the application is what it claims to be. In another example, a portable technology asset for retrieving and storing PHI in the cloud must be authenticated before retrieving data from cloud storage.

4. Clarifying the Definition of 'Availability'

a. Current Provision and Issues To Address

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details.

Department of Defense Defense Acquisition Regulations System [Docket Number DARS-2023-0015; OMB Control Number 0704-0225] **AGENCY:** Defense Acquisition Regulations System; Department of Defense (DoD). **ACTION:** Notice. **SUMMARY:** The Defense Acquisition Regulations System has submitted to OMB for clearance the following proposal for collection of information under the provisions of the Paperwork Reduction Act. **DATES:** Consideration will be given to all comments received by July 24, 2023. **ADDRESSES:** Written comments and recommendations for the proposed information collection should be sent within 30 days of publication of this notice to <https://www.reginfo.gov/public/do/PRAMain>. Find this particular information collection by selecting 'Currently under 30-day Review-Open for Public Comments' or by using the search function. You may also submit comments, identified by docket number and title, by the following method: Federal eRulemaking Portal: <https://www.regulations.gov>. Follow the instructions for submitting comments. **FOR FURTHER INFORMATION CONTACT:** Angela Duncan, 571-372-7574, or whs.mc-alex.esd.mbx.dd-dod-information-collections@mail.mil. **SUPPLEMENTARY INFORMATION:** Title and OMB Number: Defense Federal Acquisition Regulation Supplement (DFARS), Part 204, Administrative Matters and Related Clause at 252.204; OMB Control Number 0704-0225. **Affected Public:** Businesses or other for-profit and not-for profit institutions. **Respondent's Obligation:** Required to obtain or retain benefits. **Frequency:** On occasion. **Number of Respondents:** 236. **Responses per Respondent:** Approximately 1.56. **Annual Responses:** 369. **Average Burden per Response:** Approximately 3 hours. **Annual Burden Hours:** 1,107. **Needs and Uses:**

A covered entity or business associate must comply with the applicable standards, implementation specifications, and requirements of this subpart with respect to electronic protected health information of a covered entity.

§ 164.304 Definitions. As used in this subpart, the following terms have the following meanings: **Access** means the ability or the means necessary to read, write, modify, delete, transmit, or communicate data/information or otherwise use any component of an information system. (This definition applies to 'access' as used in this subpart, not as used in subpart D or E of this part.) **Administrative safeguards** are administrative actions and related policies and procedures to manage the selection, development, implementation, and maintenance (including updating and modifying) of security measures to protect electronic protected health information, and to manage the conduct of the covered entity's or business associate's workforce in relation to the protection of that information. **Authentication** means the corroboration that a person or technology asset is the one they are claiming to be. **Availability** means the property that data or information is accessible and useable upon demand by an authorized person or technology asset. **Confidentiality** means the property that data or information is not made available or disclosed to unauthorized persons, technology assets, or processes. **Deploy** means to configure technology for use and implement such technology. **Electronic information system** means interconnected set of electronic information resources under the same direct management control that shares common functionality. An electronic information system generally includes technology assets, such as hardware, software, electronic media, information, and data. **Encryption** means the use of an algorithmic process to transform data into a form in which there is a low probability of assigning meaning without use of a confidential process or key. **Facility** means the physical premises and the interior and exterior of a building(s). **Implement** means to put into effect and be in use, operational, and function as expected throughout the covered entity or business associate. **Information system** means an interconnected set of information resources under the same direct management control that shares common functionality. An information system generally includes hardware, software, information, data, communications, and people. **Integrity** means the property that data or information have not been altered or destroyed in an unauthorized manner. **Malicious**

software means software or firmware intended to perform an unauthorized action or activity that will have adverse impact on an electronic information system and/or the confidentiality, integrity, or availability of electronic protected health information. Examples include but are not limited to viruses, worms, Trojan horses, spyware, and some forms of adware. Multi-factor authentication

Some commenters suggested changes to prioritize different kinds of contracts, programs, or companies earlier or later in the implementation plan, rather than basing the phase-in on assessment type. For example, one suggested capping the number of contracts with CMMC requirements each year. Another suggested phasing in by increasing the numerical assessment score required for compliance, with additional time permitted for POA&M close-out beyond the current limit of 180 days. Another suggested reversing the phase-in to begin with CMMC Level 3. Several commenters requested extension of the phase-in plan to allow more time. One speculated that tens of thousands of contractors would require certification in less than 18 months. One commenter suggested the DoD modify the timing of implementation for CMMC levels 2 and 3, and that DoD consider allowing sufficient time to develop a robust CMMC ecosystem and demonstrate the CMMC model before full implementation. Flexibility in the implementation plan that allows Program Managers and requiring activities to include CMMC requirements earlier in the plan than will be mandated by policy also generated questions and comments. Some commenters asked whether this could result in the DoD applying CMMC requirements to previously awarded contracts or asked that the rule specify they will apply only to new contracts. Another asked about opportunities to renegotiate the contract ceiling price if CMMC assessments are required for option period exercise. One commenter asked that the rule be revised to exclude these flexibilities to result in an on/off approach to implementation. Another commenter asked what mechanisms the DoD would have to change the pace of implementation or monitor the contracts that include CMMC requirements. Response: The DoD lacks the authority to implement CMMC as a Federal-wide program. The 48 CFR part 204 CMMC Acquisition rule for CMMC will be updated to align with this 32 CFR part 170 CMMC Program rule and will modify DFARS clause 252.204-7021. CMMC Phase 1 implementation will commence when both the 32 CFR part 170 CMMC Program rule and the 48 CFR part 204 CMMC Acquisition rule are in effect. Some commenters may have overlooked that § 170.3(e) states Phase 1 begins on the effective date of this 32 CFR part 170 CMMC Program rule or the complementary 48 CFR part 204 CMMC Acquisition rule, whichever occurs later. The implementation plan describes when CMMC level requirements will appear in solicitations, it does not define a timeframe by which all contractors must be certified. During the first phases of the plan, a majority of CMMC requirements will be for self-assessment.

The CAICO has no FOCI requirement because they do not have knowledge of the OSC's network or potential vulnerabilities identified in the assessment process. Per § 170.9(b)(5), the CMMC Program implements the FOCI program that is managed by DCSA. Potential FOCI exemptions are outside the scope of this 32 CFR part 170 CMMC Program rule and must be addressed through international arrangements or agreements. 2. Personnel Security Comment: There were numerous comments regarding the Tier 3 Personnel Security requirements. Several comments recommended editorial clarification. Multiple comments requested clarification on what not eligible meant and what is the equivalent process. One comment recommended the Tier 3 background investigation be required for all authorized personnel while two comments recommended eliminating the Tier 3 background investigation requirement. Two other comments requested clarification on why a Tier 3 investigation is required when no secret information is handled and there is no clearance granted. Another comment requested clarification on the Tier 3 process. Three comments requested clarity on the citizenship requirements and how the Tier 3 requirement will be enforced for international C3PAO's. Another comment recommended adding a requirement for CMMC Instructors and Assessors to report to the CAICO within 30 days of conviction, or guilty pleas to certain crimes. Response: In coordination with the OUSD/I&S, the DoD CIO evaluated requirements for the CMMC Ecosystem. Based on the access to sensitive unclassified information, a Tier 3 background investigation that results in determination of national security eligibility is required as specified in this rule. The concept of not eligible in § 170.9(b)(4) is intended to cover those applicants who do not meet the entrance requirements for a DCSA Tier 3 background investigation, it is not an alternative for applicants who do not pass its Tier 3 background investigation. The DCSA maintains a record of all background investigation information in the Personnel Vetting Records system of records, DUSDI 02-DoD, as published in the Federal Register. The details of the Tier 3 background investigation are included in this rule to inform the public of the CMMC requirement and that the investigation will not result in a clearance. The DoD declines to remove reference to the Standard Form 86 from the rule. All documentation and records for the background investigation process must be provided in English; rulemaking as a

Federal regulation requires this level of detail to ensure clarity of understanding and interpretation. Details about background investigation equivalency is available from DCSA at www.dcsa.mil/Industrial-Security/International-Programs/Security-Assurances-for-Personnel-Facilities/. As stated in the 32 CFR part 170

Because outbreaks whose investigations are prematurely terminated may recur, the benefits from reducing that number may be high (if many people continue to become ill as a result of the recurrence). Based on FDA outbreak investigation information, the average number of reported illnesses in outbreaks that occurred between the years 2000 and 2003 was approximately 65. However, many illnesses from outbreaks go unreported, so the average total number of illnesses from an outbreak is much larger than the reported number. Using the estimated average ratio of total illnesses to reported illnesses reported earlier, we estimate that by avoiding just one outbreak recurrence, approximately 559 persons would avoid becoming ill. Traceback durations may be different for processed food sold in packages with labels with identifying barcodes than for fresh food items sold in packages with no labels. Eggs and fresh produce account for 90 percent of all outbreaks investigated by FDA, while labeled packaged foods account for only 10 percent (Ref. 2). To determine the likely length of time it takes to investigate a packaged food product, we use a range that includes the low end, where investigators are able to obtain the exact package that contains the identifying barcodes, and the high end that assumes the package, with the identifying barcodes, is not available. In the latter case, any subsequent recalls would likely include more foods than the implicated lot. The final rule relaxes the proposed requirement for lot codes to be established and maintained on all records. If FDA were to require all persons, including distributors, transporters, and retailers, to include lot numbers in the records they establish and maintain under this final rule, the traceback durations for many products would be reduced and would be comparable to those currently reported for tracebacks of packaged products that contain barcode information. If all retailers and distributors were required to establish and maintain lot codes for all processed products, then the duration of the traceback component of an outbreak investigation for many products could be reduced to 1 to 14 days. Examples of reported traceback times for fresh products and for packaged products that contain lot code information in bar code format are reported in table 9 of this document.

	Most Likely	Low	High
Eggs and fresh produce	6 to 8 weeks	2 to 5 weeks	12 weeks
Packaged products	3 days	1 day	14 days

1 Estimates reported in Ref. 2 of this document.

8. The Duration of Investigative Visits

3.3.1 | The find Comm and | 29 | | 3. 3.3.1 The find Command The^mf command [Sun88a, 183-185] is a general-purpose command for searching the file system. 3.3.1 .

(C) The first page, index, or table of contents will include a list, including page numbers, of all annexes and appendices. (D) The total number of pages will be stated on the first page. (E) All annexes or appendices will include the date of the original document and the purpose of the new text (addition or substitution) on the first page. (iii) One of the following markings will be applied to NATO documents that contain ATOMAL information: (A) This document contains U.S. ATOMIC Information (RESTRICTED DATA or FORMERLY RESTRICTED DATA) made available pursuant to the NATO Agreement for Cooperation Regarding ATOMIC Information, dated 18 June 1964, and will be safeguarded accordingly. (B) This document contains UK ATOMIC Information. This information is released to NATO including its military and civilian agencies and member states on condition that it will not be released by the recipient organization to any other organization or government or national of another country or member of any other organization without prior permission from H.M. Government in the United Kingdom. (iv) Working papers will be retained only until a final product is produced and in accordance with § 117.15(e)(3). (11) Classification guidance. Classification guidance will be in the form of a NATO security aspects letter and a security requirements checklist for NATO contracts, or a Contract Security Classification Specification, or equivalent. (i) If adequate classification guidance is not received, the contractor will contact the CSA for assistance. (ii) NATO classified documents and NATO information in other documents will not be declassified or downgraded without the prior written consent of the originating activity. (iii) Recommendations concerning the declassification or downgrading of NATO classified information will be forwarded to the CUSR. (12) Further distribution. The contractor will not release or disclose NATO classified information to a third party or outside the contractor's facility for any purpose without the prior written approval of the contracting agency. (printed page 83356) (13) Storage of NATO documents. NATO classified documents will be stored as prescribed for U.S. documents of an

equivalent classification level, except as follows: (i) NATO classified documents will not be comingled with other documents. (ii) Combinations for containers used to store NATO classified information will be changed annually. The combination also will be changed when an individual with access to the container departs or no longer requires access to the container, and if the combination is suspected of being compromised. (iii) When the combination is recorded it will be marked with the highest classification level of documents stored in the container as well as to indicate the level and type of NATO documents in the container. The combination record must be logged and controlled in the same manner as NATO classified documents. (14) International transmission.

(f) The Army system of records notices for a particular type of record will state whether the Secretary of the Army has authorized a particular general and specific exemption to a certain type of record. The Army system of records notices are published on the Defense Privacy and Civil Liberties Division's website:

<http://dpcl.dod.mil/Privacy/DODComponentArticleList/tabid/6799/Category/278/departments-of-the-army.aspx> .

(g) Exempt Army records. The following records may be exempt from certain parts of the Privacy Act: (1) System identifier and name. A0020-1 SAIG, Inspector General Records. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and (k) (5) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d) because access to such records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violations of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information is retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought.

Comments and recommendations on the proposed information collection should be sent to Ms. Susan Minson, DoD Desk Officer, at Oira_submission@omb.eop.gov . Please identify the proposed information collection by DoD Desk Officer, the Docket number, and title of the information collection. You may also submit comments, identified by docket number and title, by the following method: Federal eRulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. DoD Clearance Officer: Ms. Angela James. Requests for copies of the information collection proposal should be sent to Ms. Angela James at whs.mc-alex.esd.mbx.dd-dod-information-collections@mail.mil . Jennifer D. Johnson, Regulatory Control Officer, Defense Acquisition Regulations System. [FR Doc. 2020-28774 Filed 12-28-20; 8:45 am] BILLING CODE 5001-06-P

, as amended. Specifically, in areas of operations which require enhanced coordination of PSC and PSC personnel working for U.S. Government (U.S.G.) agencies, the Secretary of Defense may designate such areas as areas of combat operations or other significant military operations for the limited purposes of this part. In such an instance, the standards established in accordance with this part would, in coordination with the Secretary of State, expand from covering only DoD PSCs and PSC personnel to cover all U.S.G.-funded PSCs and PSC personnel operating in the designated area. The requirements of this part shall not apply to a nonprofit nongovernmental organization receiving

grants or cooperative agreements for activities conducted within an area of other significant military operations if the Secretary of Defense and the Secretary of State agree that such organization may be exempted. An exemption may be granted by the agreement of the Secretaries under this paragraph on an organization-by-organization or area-by-area basis. Such an exemption may not be granted with respect to an area of combat operations. (b) Prescribes policies applicable to all: (1) DoD PSCs and PSC personnel performing private security functions during contingency operations outside the United States. (2) USG-funded PSCs and PSC personnel performing private security functions in an area of combat operations or, with the agreement of the Secretary of State, other significant military operations as designated by the Secretary of Defense. § 159.3 Definitions. Unless otherwise noted, these terms and their definitions are for the purpose of this part. Area of combat operations . An area of operations designated as such by the Secretary of Defense for the purpose of this part, when enhanced coordination of PSCs working for U.S.G. agencies is required. Contingency operation . A military operation that is either designated by the Secretary of Defense as a contingency operation or becomes a contingency operation as a matter of law (10 U.S.C. 101(a)(13)). It is a military operation that: (1) Is designated by the Secretary of Defense as an operation in which members of the Armed Forces are or may become involved in military actions, operations, or hostilities against an enemy of the United States or against an opposing military force; or (2) Results in the call or order to, or retention on, active duty of members of (printed page 49656) the uniformed services under section 688, 12301(a), 12302, 12304, 12305, 12406, of 10 U.S.C., chapter 15 of 10 U.S.C. or any other provision of law during a war or during a national emergency declared by the President or Congress. Contractor . The contractor, subcontractor, grantee, or other party carrying out the covered contract. Covered contract

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 viii Acknowledgments 155 The authors gratefully acknowledge and appreciate the contributions from individuals and organizations in the public and private sectors whose constructive comments improved the overall quality, thoroughness, and usefulness of this publication. In particular, the authors wish to thank Jeffrey Eyink from the Department of Defense (DOD) Chief Information Office for his contributions to this update. The authors also wish to thank the NIST technical editing and production staff · Jim Foti, Jeff Brewer, Eduardo Takamura, Jeremy Licata, Isabel Van Wyk, and Cristina Ritfeld · for their outstanding support in preparing this document for publication. NIST

adversarial proceedings that are subject to rules of evidence). Any information prepared in anticipation of such actions or proceedings, including information prepared to advise DoD officials of the possible legal or other consequences of a given course of action, is protected. The exemption is similar to the attorney work-product privilege except that it applies even when the information is prepared by non-attorneys. The exemption does not apply to information compiled in anticipation of criminal actions or proceedings. (c) Exempt Records Systems. Pursuant to 5 U.S.C. 552a(k)(1) , all systems of records maintained by DoD will be exempt from the access provisions of 5 U.S.C. 552a(d) and the notification of access procedures of 5 U.S.C. 522a(e)(4)(H) to the extent that the system contains any information properly classified under Executive Order 13526 , and is required by the Executive Order to be kept secret in the interest of national defense or foreign policy. This exemption, which may be applicable to parts of all DoD systems of records, is necessary because certain record systems not otherwise specifically designated for exemptions herein may contain isolated items of information which have been properly classified. (d) Exempt records in non-exempt systems. Exempt records temporarily in the custody of another DoD Component are considered the property of the originating DoD Component. Access to these records is controlled by the system notices and rules of the originating DoD Component. Exempt records that have been incorporated into a nonexempt system of records are still exempt but only to the extent to which the provisions of the Act for which an exemption has been claimed are identified. An exemption claimed for the system of records from which the record is obtained remains in effect when the purposes underlying the exemption for the record are still valid and necessary to protect the contents of the record. If a record is accidentally misfiled into a system of records, the system notice and rules for the system in which it should actually be filed shall govern. § 310.13 Exemptions for DoD-wide systems. (a) Use of DoD-wide exemptions. DoD-wide exemptions for DoD-wide systems of records are established pursuant to 5 U.S.C. 552a(j) and (k) of the Privacy Act. (b) Promises of confidentiality. (1) Only the identity of and information furnished by sources that have been given an express promise of confidentiality may be protected from disclosure under this section, consistent with (k)(2), (k)(5), and (k)(7) of the Privacy Act, as applicable. However, the identity

of sources who were given implied promises of confidentiality in inquiries conducted before September 27, 1975, also may be protected from disclosure.

Removing ~~program~~ and adding in its place ~~Program~~ in the section heading. b. In paragraph (a): i. Removing ~~DIB CS program~~ and adding in its place ~~DIB CS Program~~ wherever it appears. ii. Removing ~~DIB participants~~ and adding in its place ~~DIB CS Program participants~~. c. In paragraph (b): i. Removing ~~DIB CS participants~~ and adding in its place ~~DIB CS Program participants~~. ii. Removing ~~http://www.dhs.gov/enhanced-cybersecurity-services~~ and adding in its place ~~https://www.cisa.gov/enhanced-cybersecurity-services-ecs~~. d. In paragraph (c): i. Removing ~~DIB CS program~~ and adding in its place ~~DIB CS Program~~. ii. Removing ~~obligate the DIB participant~~ and adding in its place ~~obligate the DIB CS Program participant~~. iii. Removing ~~taken by the DIB participant~~ and adding in its place ~~taken by the DIB CS Program participant~~. iv. Removing ~~taken on the DIB participant's~~ and adding in its place ~~taken on the DIB CS Program participant's~~. e. In paragraph (d): i. Removing ~~DIB participant's participation~~ and adding in its place ~~DIB CS Program participant's participation~~. ii. Removing ~~DIB CS program~~ and adding in its place ~~DIB CS Program~~. iii. Removing ~~approval of the DIB participant~~ and adding in its place ~~approval of the DIB CS Program participant~~. f. In paragraph (e): i. Removing ~~DIB participant~~ and adding in its place ~~DIB CS Program participant~~ wherever it appears. ii. Removing ~~DIB CS program~~ and adding in its place ~~DIB CS Program~~. g. Adding ~~change of status as a defense contractor,~~ after ~~Upon termination of the FA,~~ in paragraph (f). h. In paragraph (g): i. Removing ~~DIB participants' rights~~ and adding in its place ~~DIB CS Program participants' rights~~. ii. Removing ~~DIB CS program~~ and adding in its place ~~DIB CS Program~~. iii. Removing ~~the requirement for DIB participants~~ and adding in its place ~~the requirement for DIB CS Program participants~~. 9. Revise § 236.7 to read as follows: § 236.7 DoD's DIB CS Program requirements. (a) To participate in the DIB CS Program, a contractor must own or operate a covered contractor information system and shall execute (printed page 27839) the standardized FA with the Government (available during the application process), which implements the requirements set forth in §§ 236.5 and 236.6 and this section. (b) In order for DIB CS Program participants to receive classified cyber threat information electronically, the company must be a cleared defense contractor and must: (1) Have an existing active facility clearance level (FCL) to at least the Secret level in accordance with 32 CFR part 117 ; (2) Have or acquire a Communication Security (COMSEC) account in accordance with 32 CFR part 117 , which provides procedures and requirements for COMSEC activities; (3) Have or acquire approved safeguarding for at least Secret information, and continue to qualify under 32 CFR part 117 for retention of its FCL and approved safeguarding; and

1.337, 1.345, and 1.352 (records redesign) \$205,239,000 1.337, 1.345, and 1.352 (additional records maintenance) \$114,701,000 1.337, 1.345, and 1.352 (learning for new firms) \$8,508,000 Discounted present value of total costs 2 \$1,406,356,000 1 The annual costs are reported in undiscounted terms. Records access planning costs and records retention costs are estimated to be zero and are not reported here. 2 The reported discounted present value of total costs assumes a 7-percent discount rate and a 20-year time horizon over which annual costs are summed. (printed page 71641) The final rule will help reduce the numbers of people who become ill during a foodborne outbreak by reducing the time required for preventive action. Furthermore, the final rule will reduce the recurrence of outbreaks that may have been prevented had nonexistent or poor records quality not resulted in prematurely terminating the initial traceback investigation. In addition to relaxing elements of the requirement for records to contain lot code information, the reduction in benefits from the final rule compared to the proposal results from excluding foreign facilities except those that transport food in the United States, relaxing recordkeeping requirements for food contact substance facilities, relaxing recordkeeping requirements for very small retail facilities, adopting retention requirements based on the NIST food shelf life definitions, and relaxing the records access requirement from 4 and 8 hours to as soon as possible, not to exceed 24 hours. The estimated costs and benefits of many policy options considered in this section summarize the details of the analyses based on the comments FDA received and are reported in the following tables. The costs for the options are reported in present value terms for both 7 percent-and 3-percent discount rates. We summed the discounted annual costs over a 20 year horizon to obtain the estimate of the total costs. A 20-year horizon for measuring the costs from the regulation is reasonable, given uncertainty in the regulatory environment and technological change. The reduction in benefits relative to the proposal from each modification is based on the impact that each option would likely have on traceback times and the rates of traceback completions. Again, the benefits are based solely on food safety concerns (i.e., typical traceback scenarios with which FDA has been involved) and do

not take into account food security concerns. In table 16 of this document we compare the costs of the options considered to the baseline option of the proposed rule, with the caveat that the provision requiring all records to contain lot code information, which was included in the proposed rule, is no longer in the baseline. All other provisions included in the proposed rule are in the baseline for this analysis.

When a request for records is received, DoD FOIA Offices shall open a file in a formal control system designed to ensure accountability and compliance with the FOIA. The control system should include the data elements needed to compile the statistics required in the annual FOIA report or other reports required by another authority. Each request shall be assigned a unique tracking number. (b) Multi-track processing. (1) When a FOIA Office has a significant number of pending requests, the requests shall be processed in a multi-track system. (2) DoD FOIA Offices shall establish a minimum of three processing tracks, all based on a first-in/first-out concept and with requests ranked by date of receipt. One track shall be for simple requests, one for complex requests, and one for expedited requests. Each FOIA Office shall determine whether a request is simple or complex. Requesters whose requests are categorized as 'complex' shall be given an opportunity to limit in writing the scope of the request in order to qualify for the simple track. (c) Expedited processing. Two circumstances merit expedited processing according to the procedures that follow. These same procedures apply to requests for expedited processing of administrative appeals. (1) Compelling need. Expedited processing shall be granted to a requester upon a specific request for such and demonstration of a compelling need for the information. The DoD Component shall respond to the requester with the determination whether to grant or deny expedited processing within 10 calendar days after receipt of the request. Once the DoD Component decides to grant expedited processing, the request shall be processed as soon as practicable. Actions by the DoD Components to initially deny or affirm the initial denial on appeal of a request for expedited processing, and failure to respond in a timely manner shall be subject to judicial review if the requester seeks relief in United States District Court. (i) 'Compelling need' is the failure to obtain the records on an expedited basis could reasonably be expected to pose an imminent threat to the life or physical safety of an individual, or that the information is urgently needed by an individual primarily engaged in disseminating information in order to inform the public concerning actual or alleged Federal Government activity. (A) 'An individual primarily engaged in disseminating information' is a person whose primary activity involves publishing or otherwise disseminating information to the public. To meet this criterion, an organization or person must establish that information dissemination is their principal professional activity or occupation, and not an incidental or secondary activity.

Additional information about this publication is available at <https://csrc.nist.gov/pubs/sp/800/63/A/4/final>, including related content, potential updates, and document history. 3.7. Additional Requirements for Federal Agencies 4.3.7. On-Site Attended Requirements · Colocated Agent

CIS Safeguard 5.2 · Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA. Implementation Groups: 1,2,3 Asset Type: users Security Function: protect Parent Control: Account Management

Estimates consist of costs for a contractor to submit to SPRS an initial and affirmation of compliance that the covered contractor information system is compliant with and will maintain compliance with the requirements of the applicable CMMC Level. Where POA&Ms are allowed, an affirmation must be submitted with the POA&M closeout. Except for Small Entities for Level 1 and Level 2, it is assumed the task requires the same labor categories and estimated hours as the final reporting phase of the assessment. (b) Comparison to the Initial CMMC Program Cost Analysis Public comments on the initial CMMC Program indicated that cost estimates were too low. Updated CMMC Program cost estimates account for that feedback with the following improvements: Allowance for outsourced IT services. Increased total time for the contractor to prepare for the assessment, including limited time for learning the reporting and affirmation processes. Allowance for use of consulting firms to assist with the assessment process. Time for a senior level manager to review the assessment and affirmation before submitting the results into SPRS. Updated government and contractor labor rates that include applicable burden costs. As a result, some cost estimates for the updated CMMC Program may be higher than those included in the initial CMMC Program. (c) Cost Analysis/Estimates by CMMC Level CMMC Level 1 Self-Assessment and Affirmation Costs for Small

Business Entities Nonrecurring and recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with CMMC Level 1 since it is assumed the contractor has implemented basic safeguarding requirements. [63] Self-Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 1 assessment and affirmation is *\$5,977 (as summarized in table 1). A Level 1 self-assessment is conducted annually, and is based on the assumptions detailed below: · Phase 1: Planning and preparing for the assessment: \$1,803 A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) An external service provider (ESP) [64] for 4 hours ($\$260.28 \times 4\text{hrs} = \$1,041$) · Phase 2: Conducting the self-assessment: \$2,705 A director (MGMT5) for 6 hours ($\$190.52/\text{hr} \times 6\text{hrs} = \$1,143$) An external service provider (ESP) for 6 hours ($\$260.28 \times 6\text{hrs} = \$1,562$) · Phase 3: Reporting of Assessment Results into SPRS: \$909 A director (MGMT5) for 2 hours ($\$190.52/\text{hr} \times 2\text{hrs} = \381) An external service provider (ESP) for 2 hours ($\$260.28/\text{hr} \times 2\text{hrs} = \521) A staff IT specialist (IT4) for 0.08 hours [65] ($\$86.24/\text{hr} \times 0.08\text{hrs} = \7) · Affirmation: initial affirmation post assessment: \$560 Reaffirmations: It is estimated that the costs to reaffirm a CMMC Level I annually for a small entity is \$560 · A director (MGMT5) for 2 hours ($\$190.52/\text{hr} \times 2\text{hrs} = \381) · A staff IT specialist (IT4) for 2.08 hours ($\$86.24/\text{hr} \times 2.08\text{hrs} = \179) Summary:

(Response) The agency does not agree completely that distribution centers and retail outlets do not know many of the information items. The agency agrees, however, that including information pertaining to lot or code numbers of foods in the required records is not practical for distribution centers and retail outlets, given current business practices. FDA has, therefore, deleted this requirement. Instead, the final regulation now only requires that persons who manufacture, process, or pack food keep records on the lot or code number or other identifier of the food, and only to the extent this information exists. Moreover, to minimize the burden this regulation may have on affected parties, FDA is not specifying the form or format of the records that must be established and maintained and is not requiring electronic records. (Comment 12) Several comments applaud the agency's efforts in proposing a rule that appears to be designed to work with the food industry as efficiently and effectively as possible to address credible threats without imposing undue burdens. One comment urges the agency to issue the final regulations as expeditiously as possible to enhance compliance with the provisions of the Bioterrorism Act. The comment states that, by finalizing the regulations in conjunction with the interim final rules entitled ·Registration of Food Facilities Under the Public Health Security and Bioterrorism Preparedness and Response Act of 2002· (the registration interim final rule) (68 FR 58894 , October 10, 2003) and ·Prior Notice of Imported Food Under the Public Health Security and Bioterrorism Preparedness and Response Act of 2002· (the prior notice interim final rule) (68 FR 58974 , October 10, 2003), the education and training that will be necessary for compliance with the regulations can be done together and the internal policy and procedures for companies can be designed to meet all of the obligations under the final rule. The comment further states that this is the reason that Congress intended regulations to be issued within 18 months of the effective date of the Bioterrorism Act. (Response) The agency has acted expeditiously in issuing all of the regulations under the Bioterrorism Act and has developed and published final regulations as quickly as possible. With respect to education and training, as stated previously, the agency intends to conduct extensive outreach to stakeholders for this final rule that is similar to outreach the agency conducted for the registration and prior notice interim final rules.

- 'Secure by Design': Uses Secure Code Storage; Secure Code Training (e.g., training starting on day one, and regularly ongoing); Secure Code Scanning (e.g., tracking vulnerabilities, hard-coded secrets, code leaks and binaries); Policy/Framework (e.g., using System Development Lifecycle (SDLC), Open Web Application Security Project(OWASP), NIST); Industry Maturity Model (using the Software Assurance Maturity Model (SAMM)); Application Lifecycle Management/Product Lifecycle Management (ALM/PLM) Integration into Development Model (using Quality Service Model Operating System (SMOS)); - 'Secure in Use': Employs mechanisms such as participating in the Bug90 program, penetration testing, and tracking metrics; and - 'Secure Thru Trust': Seeks to build connections with customers including a broad range of organizational partnerships, direct customer engagements, and the use of media to disseminate information about Zebra product security. When prompted by a participant question on whether all IoT companies need a CPSO, speaker David Barzilai, Karamba Security, indicated that would not always be the case. He suggested that in the case of OEMs focusing on 'low-security-awareness markets' or markets where attacks might not necessarily be an issue, the OEM could make a risk-based decision to allocate an architect from R&D who could serve in the CPSO capacity to assure the product security posture. Tools to analyze supply chain

outputs (e.g., binary analyzers and SBOMs) are also available, improving, and becoming more common. There was association between binary analysis for supply chain security following NIST recommendations for using SBOM, and vulnerability disclosure reports were viewed by the panel as an excellent source of security information.

Wearable devices made specifically for public safety are slowly being introduced to the marketplace. Outside of public safety specific wearable devices, PSCR Engineers also acquired wearable devices that may assist first responders in different ways, such as awareness, communication, and data sharing. Examples of wearable devices include the following: | Cybersecurity Framework Function | Guidance |

|-----|-----|
Identify | Identify your public safety needs and devices | | Protect | Protect yourself by applying security and training users | | Detect | Detect issues by logging and monitoring your devices | | Respond | Respond with a prepared plan | | Recover | Recover by implementing the plan and constantly improving | ## 5.1.2 Protect - yourself by applying security and training users

Therefore, the total estimated cost of labor, hardware, and software for 5,875 contractors to implement NIST SP 800-171 Revision 2 in the initial year is \$1,524,706,500, of which \$861,808,500 is attributed to 4,905 small businesses. The total estimated annual recurring maintenance costs are \$1,065,919,000, of which \$509,139,000 is attributed to 4,905 small businesses. b. Assess and Report Suspected CUI Incidents When the contractor discovers a suspected CUI incident, the contractor is required by the clause at FAR 52.204-XX and, when applicable, the clause at FAR 52.204-YY to: determine what CUI was or could have been improperly accessed, used, processed, stored, maintained, disseminated, disclosed, or disposed of; construct a timeline of user activity; and determine methods and techniques used to access CUI. The contractor shall report any suspected or confirmed CUI incident to the agency website or point of contact identified in the SF XXX, within 8 hours of discovery. The clause at FAR 52.204-XX also requires the contractor to include in the report as many of the applicable data elements located on the DIBNet website (<https://dibnet.dod.mil>) as are available and provide any remaining applicable data elements as soon as they become available. Subcontractors are required by FAR 52.204-XX(h) to notify the prime or next higher tier subcontractor within the same timeframe. When applicable, the clause at FAR 52.204-YY requires contractors to follow agency requirements related to the incident if it turns out CUI is involved. It is estimated that there may be 580 incident reports submitted each year and that it may take a contractor four hours to prepare and submit CUI incident reports to civilian agencies. The total estimated annual cost for CUI incident reporting for non-defense contractors is \$275,500 (580 non-defense contractors * 1 incident/non-defense contractor * 4 hours/response * \$95/hour), of which \$188,482 is attributed to 397 small businesses. c. Preserve and Protect Images for Suspected CUI Incidents and Submit Media and Data for Damage Assessments If a suspected or confirmed CUI incident has occurred on an information system, the contractor is required by the clause at FAR 52.204-XX to preserve and protect images of all known affected information systems and all relevant monitoring and packet capture data for at least 90 days from the submission of the report to allow the Government to request the media and data or decline interest during this 90 day period, after which, if no request has been made, the images need no longer be preserved.

Although the focus of [ISO 15288] is systems and software engineering processes, operational resilience, which includes cyber resiliency for systems that include or depend on cyber resources, is addressed indirectly by requiring organization-wide commitment, resources, practices, and processes. The interacting elements in the definition of a system include layers of resilience in hardware, software, data, information, humans, processes, procedures, facilities, materials, and naturally occurring physical entities. This is important because if the organization's missions or business functions require sustainability during perturbations, disruptions, disturbances, or cyber-attacks, then operational resilience practices and procedures must be applied to all of the system's assets. It would be of limited value to have resilience measures implemented in the software architecture if there is no redundancy and survivability in the hardware, if the communications networks are fragile, if critical personnel are not available (e.g., in a natural disaster or inclement weather) to operate and maintain the system, or if there are no facilities available for producing the organization's products and/or services. Providing satisfactory security controls in a computer system is in itself a system design problem. A combination of hardware, software, communications, physical, personnel and administrative- procedural safeguards is required for comprehensive security. In particular, software safeguards alone are not sufficient. An adversary

that possesses sophisticated levels of expertise and significant resources that allow it to create opportunities to achieve its objectives by using multiple attack vectors including, for example, cyber, physical, and deception.

(7) Regardless of age, all DA military personnel and all married persons are considered adults. The parents of these individuals do not have access to their medical records without written consent of the individual. (8) DOD 6025.18-R, DOD Health Information Privacy Regulation, issued pursuant to the Health Insurance Portability and Accountability Act (HIPAA) of 1996, has placed additional procedural requirements on the uses and disclosure of individually identifiable health information beyond those found in the Privacy Act of 1974 and this part. In order to be in compliance with HIPAA, the additional guidelines and procedures will be reviewed before release of an individual's identifiable health information. (e) Personal notes. (1) The Privacy Act does not apply to personal notes of individuals used as memory aids. These documents are not Privacy Act records and are not subject to this part. (2) The five conditions for documents to be considered personal notes are as follows: (i) Maintained and discarded solely at the discretion of the author; (ii) Created only for the author's personal convenience and the notes are restricted to that of memory aids; (iii) Not the result of official direction or encouragement, whether oral or written; (iv) Not shown to others for any reason; and (v) Not filed in agency files. (3) Any disclosure from personal notes, either intentional or through carelessness, removes the information from the category of memory aids and the personal notes then become subject to provisions of the Act. (f) Denial or limitation of individual's right to access. (1) Even if the information is filed and retrieved by an individual's name or personal identifier, his or her right to access may be denied if: (i) The records were compiled in reasonable anticipation of a civil action or proceeding including any action where DA expects judicial or administrative adjudicatory proceedings. The term 'civil action or proceeding' includes quasi-judicial, pre-trial judicial, and administrative proceedings, as well as formal litigation; (ii) The information is about a third party and does not pertain to the requester. A third party's SSN and home address will be withheld. However, information about the relationship between the individual and the third party would normally be disclosed as it pertains to the individual; (iii) The records are in a system of records that has been properly exempted by the Secretary of the Army from the access provisions of this part and the information is exempt from release under a provision of the Freedom of Information Act (See appendix C of this part for a list of applicable Privacy Act exemptions, exceptions, and 'Blanket' routine uses); (iv) The records contain properly classified information that has been exempted from the access provision of this part;

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. This report summarizes discussions held at the March 5, 2025 "Workshop on Foundational Cybersecurity Activities for IoT Device Manufacturers" organized by the NIST Cybersecurity for the Internet of Things (IoT) program. This workshop follows an earlier event held in December 2024 titled 'Workshop on Updating Manufacturer Guidance for Securable Connected Product Development' to identify major update areas to NIST IR 8259. Similarly, the purpose of this more recent workshop was to discuss planned updates to NIST IR 8259 and gather additional feedback on taking a product viewpoint with greater emphasis on the IoT product lifecycle, expanded discussion of risk analysis, application to industrial contexts, and cybersecurity considerations around data management to support privacy goals. Over time, NIST work has built upon the concepts introduced in the NIST IR 8259, as reflected in subsequent publications that elaborate on IoT cybersecurity for specific sectors and use cases (e.g., federal agency use of IoT, consumer use of IoT in the home or in small businesses). Internet of Things; IoT products; manufacturing; risk assessment; product lifecycle; securable products; security requirements; software development; threat modelling .

All such issued stablecoins are over-collateralized, which promotes the maintenance of the stablecoin peg since stablecoins can always be redeemed from the issuer at their pegged price. The price is further stabilized through arbitrage. If the price of the stablecoin on third-party markets falls below its peg, then borrowers of the stablecoin can purchase the stablecoin at a discount price and use it to pay off their debt positions (making a profit). When debt positions are paid

off, the provided stablecoins are burned. This reduces the overall supply, which puts an upward pressure on the price. If the price of the stablecoin on third-party markets rises above its peg, then borrowers will take on additional debt positions, which results in the minting of additional stablecoins. The borrowers can then immediately sell the newly minted stablecoins on third-party markets for a profit. This increases the overall supply, which puts a downward pressure on the price. The cryptocurrency-backed stablecoins minted through loan issuance (Section 4.2) require users to post cryptocurrency as collateral when borrowing. This mitigates the cryptocurrency losing its price peg since enough collateral should be maintained to cover all issued stablecoins. However, since the posted collateral is in the form of cryptocurrency, it may be extremely volatile. Thus, borrowers are required to over-collateralize. When borrowing, the stablecoin system will specify a minimum required collateral ratio. That is, the user must maintain a certain value of cryptocurrency collateral to cover the price of the borrowed stablecoins. If the user falls below that ratio (through the posted cryptocurrency losing value), then the user is required to post more collateral, or their collateral may be subject to liquidation. This is very similar to the maintenance of margin loans in the stock market. Margin investors in the stock market may be required to post additional collateral to cover stock market losses.

In the course of their day-to-day business dealings, warehouses may not be privy to a description of the type of food or details of its packaging sufficient to satisfy this regulation. To acquire this knowledge and maintain the required records, warehouses may incur costs in addition to those that would be incurred by the owners of the product. FDA assumes that as part of their normal business practices, warehouse facilities may be required to maintain a limited amount of information on the immediate previous source and immediate subsequent recipient of a comparable magnitude to that of the owners of the products. However, the detailed information on the product and its packaging required by the regulation may be more costly to obtain for warehouse personnel than for the owners of the product. For some products, warehouse facilities are assumed to have the same required knowledge of the required information on the stored product and its packaging as that of the owner of the product. For other products, the warehouse personnel's knowledge of the required information on the stored product and its packaging is less than that of the owner. We estimate that, for half of all food products stored, warehouse personnel have the same amount of the required knowledge of the food and its packaging as the owner of the product, and that the additional records maintenance costs would be comparable to those incurred by the product owners. For products for which warehouses currently lack the required knowledge, we assume that the additional records maintenance costs for warehouse facilities would be approximately 50 percent higher than those for owners of the products. Much of the extra cost may involve contracting with product owners to provide the required information. b. Interstate conveyances and catering services sector . (Comment 209) Several comments suggest that the costs to the interstate conveyance catering industry were greatly underestimated and that this sector should be excluded from the regulation. One comment states that for airline caterers, each flight typically includes hundreds of individual foods from scores of different sources and suppliers. The comment further states that this industry is further complicated by the large number of special meal requests by individual passengers on each flight.

(Response) The exclusion in § 1.327(d) of this final rule from establishing and maintaining records of immediate subsequent recipients for food distributed directly to consumers applies to sales of bagged feed, pet food, and feed ingredients/additives over-the-counter directly to consumers and final purchasers for their own animals, unless the feed is to be used in animals that will be sold as food. If the feed is to be fed to food-producing animals, then the purchasers are not considered consumers since they are purchasing the food for a business (i.e., for the food-producing operation). The feed will remain in the food distribution system, and FDA needs records to help address credible threats of serious adverse health consequences or death to humans or animals. Therefore, under § 1.327(e), persons who operate retail food establishments that distribute food to persons who are not consumers are subject to all of the requirements in subpart J of this final rule. However, for retail food establishments, the requirements in § 1.345 of this final rule to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients that are not consumers applies as to those transactions only to the extent the information is reasonably available. In addition, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements of subpart J in this final rule, except the record access provisions for existing records under §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) 6. Retail Facility/Roadside Stands (Comment 53) One comment is concerned that the

retail exemption only applies to facilities, such as roadside stands that employ 10 or fewer (printed page 71582)

\$45. Please send subscription orders and remittances for the preceding bibliographic services to the National Bureau of Standards, Cryogenic Data Center (736) Boulder, CO 80303. . ## U.S. DEPARTMENT OF COMMERCE National Bureau of Standards Washington, D.C. 20234 OFFICIAL BUSINESS Penalty for Private Use. \$300 <!-- image --> <!-- image --> SPECIAL FOURTH-CLASS RATE BOOK

Consider a large regulated entity that may have thousands of workforce members accessing various networks and relevant electronic information systems, generating large amounts of log and audit data. Given the size, complexity, and capabilities of entities of such size, a reasonable and appropriate process for reviewing activity may include the adoption of an automated solution that performs rules-based enterprise log aggregation and analysis to identify anomalous or suspicious patterns of behavior in the regulated entity's relevant electronic information systems and the components thereof, including but not limited to workstations, in real-time and sends alerts of potential security incidents to a workforce member or team for further review and action. By contrast, for a small regulated entity, it might be reasonable and appropriate to have designated staff that manually review log files and audit trails multiple times per week. j. Section 164.308(a)(8)-Standard: Assigned Security Responsibility The Department proposes to redesignate the standard for assigned security responsibility at 45 CFR 164.308(a)(2) as proposed 45 CFR 164.308(a)(8) . OCR's enforcement experience demonstrates that, in practice, many regulated entities follow informal policies and procedures that are not documented, and have not documented the identification of the Security Official in writing. Based on OCR's enforcement experience, and consistent with existing guidance, we propose to modify the standard to specify that a regulated entity must identify in writing the Security Official who is responsible for the establishment and implementation of the policies and procedures, whether written or otherwise, and deployment of technical controls. These proposals are consistent with our general intention in this NPRM to propose to clarify that policies and procedures required by the Security Rule should be reduced to writing and to distinguish between the implementation of written policies and procedures and the deployment of technical controls. As we previously explained in guidance, [542] the purpose of this standard is to identify who would be operationally responsible for assuring that the regulated entity complies with the Security Rule. It is comparable to the Privacy Rule standard for personnel designations at 45 CFR 164.530(a)(1) , which requires all covered entities to designate a Privacy Official. The Security Official and Privacy Official can, but need not be, the same person. While one workforce member must be designated as having overall responsibility, other workforce members may be assigned specific security responsibilities (e.g.,

), the DoD published the proposed rule titled, "Department of Defense Privacy Program," with a 60-day public comment period. Two comments were received which commended the streamlining effort and expressed an interest in more detail of the proposed changes. The Department appreciates the comments and has provided additional description of the revisions to the Department of Defense Privacy Program rule above in the SUPPLEMENTARY INFORMATION . No changes were made to the regulatory text as a result of these comments. Public Comments Received on the Personnel Vetting Interim Final Exemption Rule As stated above, DoD is incorporating the final version of the Personnel Vetting Records System exemption rule published on October 17, 2018 into this DoD Privacy Program final rule in § 310.13. Two commenters submitted public comments in response to the interim final rule, neither of which required changes to § 310.13 of this final (printed page 14730) rule. One comment was not specific to the exemptions claimed for the Personnel Vetting Records System, but called attention generally to the importance of safeguarding and managing records. DoD agrees and has previously explained in its notice of the Personnel Vetting Records System, DUSDI 02-DoD (83 FR 52420 , 52425), the extensive physical, administrative, and technical safeguards that apply, as well as the records retention and disposal policies and practices. The other commenter submitted a single set of comments for both the Personnel Vetting system of records notice (83 FR 52420) and the interim final rule for the corresponding records system exemptions (83 FR 52317). DoD will respond separately to the comments pertaining specifically to the system of records notice in the electronic docket visible on Regulations.gov

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket

number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 170 [Docket ID: DoD-2023-OS-0063] RIN 0790-AL49 AGENCY: Office of the Department of Defense Chief Information Officer (CIO), Department of Defense (DoD). ACTION: Proposed rule. SUMMARY: DoD is proposing to establish requirements for a comprehensive and scalable assessment mechanism to ensure defense contractors and subcontractors have, as part of the Cybersecurity Maturity Model Certification (CMMC) Program , implemented required security measures to expand application of existing security requirements for Federal Contract Information (FCI) and add new Controlled Unclassified Information (CUI) security requirements for certain priority programs. DoD currently requires covered defense contractors and subcontractors to implement the security protections set forth in the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 Rev 2 to provide adequate security for sensitive unclassified DoD information that is processed, stored, or transmitted on contractor information systems and to document their implementation status, including any plans of action for any NIST SP 800-171 Rev 2 requirement not yet implemented, in a System Security Plan (SSP). The CMMC Program provides the Department the mechanism needed to verify that a defense contractor or subcontractor has implemented the security requirements at each CMMC Level and is maintaining that status across the contract period of performance, as required. DATES: Comments must be received by February 26, 2024. ADDRESSES: You may use the following methods to submit comments on: the proposed rule, identified by docket number DoD-2023-OS-0063 and/or Regulatory Identifier Number (RIN) 0790-AL49 and title the guidance in the Appendix documents, identified by docket number DoD-2023-OS-0096 and title the information collection requirements, identified by docket number DoD-2023-OS-0097 and title Comment Submission Methods include: Federal eRulemaking Portal: <https://www.regulations.gov> . Follow the instructions for submitting comments. Mail: Department of Defense, Office of the Assistant to the Secretary of Defense for Privacy, Civil Liberties, and Transparency, Regulatory Directorate, 4800 Mark Center Drive, Attn: Mailbox 24, Suite 08D09, Alexandria, VA 22350-1700. Instructions: All submissions received must include the agency name and docket number or RIN for this Federal Register

The Government considered whether or not to establish a new standard form to communicate CUI requirements specific to the contract. As an alternative, the FAR could prescribe only a solicitation provision and contract clause to establish offeror and contractor responsibilities related to marking and handling CUI involved in the contract but would not dictate how agencies communicate what types of CUI may be involved in the contract. Given the importance of protecting CUI, it was determined that a Standard Form is the best way to ensure the Government is properly communicating specific CUI requirements for each contract. Absent a standard form, there is a risk that agencies may not provide enough information for contractors to understand what CUI is involved in the contract and what responsibilities they have with regard to this CUI. The standard form also provides a means for contractors to uniformly communicate CUI requirements to its subcontractors.

3. 100 Percent Inspection Several aspects of this proposed rule require the contractor to provide information upon request. For example, contractors may be requested to submit supporting documentation to verify compliance with the system security plan required by NIST SP 800-171 Revision 2 in instances where the Government is dealing with a CUI incident that is a confirmed breach or an agency determines that it is necessary to verify a contractor's system security plan based on the criticality of a program and the CUI being handled on the contractor's information system (see sections B.1.e. and D.1.g. of the Regulatory Impact Analysis). Similarly, when such CUI incidents have occurred, the Government may require the contractor to submit information to verify that the contractor and its subcontractors have provided appropriate training to their employees that handle CUI, as required by the clause at FAR 52.204-XX (see sections B.1.c. and D.1.b of the Regulatory Impact Analysis). As an alternative, the Government considered whether to require contractors to submit evidence of its system security plan and evidence that employees have been trained on an annual basis. However, defense contractors should have already implemented system security plans in accordance with DFARS clause 252.204-7012 and non-defense contractors have incentive to ensure compliance with the requirements in FAR clause 52.204-XX to avoid liability for breaches of CUI that may result from improperly protecting CUI being handled on the contractor's information system. As such, implementing a 100 percent inspection requirement would unnecessarily and significantly increase the burden on contractors and the Government.

4. Implementation of NIST SP 800-171 Revision 3 This proposed rule requires contractors to implement the requirements of NIST SP 800-171 Revision 2. In May of 2024, NIST published Revision 3 to NIST SP 800-171 (see <https://csrc.nist.gov/pubs/sp/800/171/r3/final>)

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [Docket Number DARS-2025-0006; OMB Control Number 0704-0478] AGENCY: Defense Acquisition Regulations System; Department of Defense (DoD). ACTION: Supplemental notice. (printed page 1512) SUMMARY: The Defense Acquisition Regulations System has submitted to OMB for clearance the following proposal for collection of information under the provisions of the Paperwork Reduction Act. This document updates the instructions for submission of comments. DATES: DoD will consider all comments received by January 14, 2026. ADDRESSES: Written comments and recommendations for the proposed information collection should be sent within 30 days of publication of this notice to <https://www.reginfo.gov/public/do/PRAMain> . Find this particular information collection by selecting 'Currently under 30-day Review-Open for Public Comments' or by using the search function. You may also submit comments, identified by docket number and title, by the following method: Federal eRulemaking Portal: <https://www.regulations.gov> . Follow the instructions for submitting comments. FOR FURTHER INFORMATION CONTACT: Mr. Reginald T. Lucas, 571-372-7574, or whs.mc-alex.esd.mbx.dd-dod-information-collections@mail.mil . SUPPLEMENTARY INFORMATION: In the Federal Register of January 5, 2026, in FR Doc. 2025-24248 , on page 255, this supplemental notice adds an ADDRESSES caption to include public comment instructions. Title and OMB Number: Safeguarding Covered Defense Information, Cyber Incident Reporting, and Cloud Computing; OMB Control Number 0704-0478. Affected Public: Businesses or other for-profit and not-for-profit institutions. Respondent's Obligation: Required to obtain or retain benefits. Reporting Frequency: On occasion. Number of Respondents: 1,971. Responses per Respondent: 8.2, approximately. Annual Responses: 16,223. Average Burden per Response: 0.42 hours. Annual Burden Hours: 6,770. Needs and Uses: Offerors and contractors must report cyber incidents on unclassified networks or information systems, within cloud computing services, and when they affect contractors designated as providing operationally critical support, as required by statute.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations. XACML and NGAC are ABAC standards for facilitating policy-preserving user executions of data service capabilities (data service operations on data service resources). In general, data services are a class of applications that provide users with capabilities to consume, manipulate, manage, and share data. Examples of data services include applications such as 'time and attendance reporting', payroll processing, corporate calendaring, and health benefits management, all with a strong need for access control. XACML and NGAC provide a single generic access control facility for applications, resulting in a dramatic alleviation of many of the administrative, interoperability, and usability challenges otherwise faced by enterprises. This is achieved by removing the access control logic from the access control mechanism in the operating environment of each application. Instead the access control logic is implemented using a common set of access control modules that provide access decision functionality, which support these applications using a centralized policy and attribute repository.

Several public commenters asked whether and how the CMMC rule content would apply to foreign based or international companies, either as companies seeking to comply with assessment requirements or as companies seeking to participate in the CMMC Ecosystem. Some questions asked for interpretation of requirements for specific scenarios, such as how CMMC requirements might affect Status of Forces Agreements for DoD installations overseas. Others asked about application of flow-down requirements to foreign subcontractors, including in circumstances when DFARS clauses do not apply or when international agreements supersede application of DFARS clause 252.204-7012. A few comments asked

how foreign or multinational corporations with facilities abroad can attain CAGE codes, access SPRS, or meet other aspects of CMMC requirements. Some asserted that specific systems contractors need to access, such as SPRS and PIEE, are not designed to accommodate foreign address formats and requested modifications or alternative options to facilitate submission of CMMC affirmations. One commenter suggested that assessment of foreign contractor information systems should only be conducted by the host country, and asked whether foreign contractors should be partially exempted from CMMC requirements. Response: CMMC Program requirements are applicable when DoD requires processing, storing, or transmitting of either FCI or CUI during performance of a DoD contract. CMMC Program requirements would not apply to a DoD Installation's communication with a Host Nation government on matters related to the Installation. CMMC program requirements apply to all DoD contractors alike when contract performance will require processing, storing, or transmitting of FCI or CUI on contractor-owned information systems. This 32 CFR part 170 CMMC Program rule does not permit partial exemption of assessment requirements for foreign contractors. Any discussion of exemptions or deviations for foreign businesses are outside the scope of the 32 CFR part 170 CMMC Program rule and must be addressed through government-to-government international arrangements or agreements. Pathways and timelines for achieving these agreements are outside the scope of this rule. CMMC requirements apply to both domestic and international primes and flow down to subcontractors throughout the supply chain if their information systems process, store, or transmit FCI or CUI. CMMC requirements are based upon the type of information processed and shared, regardless of where the company is headquartered or operates. Certification requirements for subcontractors are addressed in § 170.23(a)(1) through (4). For additional information about flow-down of contractual requirements, see the 48 CFR part 204

However, neither FAR clause 52.204-21 nor DFARS clause 252.204-7012 provide for DoD verification of a contractor's implementation of the basic safeguarding requirements specified in FAR 52.204-21 nor the security requirements specified in NIST SP 800-171 Rev 2, implementation of which is required by DFARS clause 252.204-7012, prior to contract award. As part of multiple lines of effort focused on the security and resilience of the DIB, the Department is working with industry to enhance the protection of FCI and CUI within the DoD supply chain. Toward this end, DoD has developed the CMMC Program. CMMC 2.0-Requirements The CMMC Program requirements will be implemented through the DoD acquisition and contracting process. With limited exceptions, the Department intends to require compliance with CMMC as a condition of contract award. Once CMMC is implemented, the required CMMC level for contractors will be specified in the solicitation. In accordance with the implementation plan described in 32 CFR 170.3(e), CMMC compliance or certification requirements will apply to new DoD solicitations and contracts, and shall flow down to subcontractors, based on the sensitivity of the FCI and CUI to be processed, stored or transmitted to or by the subcontractor. Before contract award, the offeror must achieve the specified CMMC level for the contractor information system (e.g., enterprise network, network enclave) that will process, store, or transmit the information to be protected. The contractor or subcontractor will also submit affirmations in the Supplier Performance Risk System (SPRS). An overview of requirements at each level is shown: CMMC Level 1-Self-Assessment CMMC Level 1 Self-Assessment requires compliance with basic safeguarding requirements to protect FCI are set forth in FAR clause 52.204-21. CMMC Level 1 does not add any additional security requirements to those identified in FAR 52.204-21. Organizations Seeking Assessment (OSAs) will submit the following information in SPRS prior to award of any prime contract or subcontract and annually thereafter: 1. the results of a self-assessment of the OSA's implementation of the basic safeguarding requirements set forth in 32 CFR 170.15 associated with the contractor information system(s) used in performance of the contract; and 2. an initial affirmation of compliance, and then annually thereafter, an affirmation of continued (printed page 89082) compliance as set forth in 32 CFR 170.22. 3. the Level 1 Self-Assessment cost burden will be addressed as part of the 48 CFR acquisition rule. CMMC Level 2-Self-Assessment CMMC Level 2 Self-Assessment requires compliance with the security requirements set forth in NIST SP 800-171 Rev 2 to protect CUI. CMMC Level 2 does not add any additional security requirements to those identified in NIST SP 800-171 Rev 2. OSAs will submit the following information in SPRS prior to award of any prime contract or subcontract:

(E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. (17) [Reserved] (18) System identifier and name. GNSA 25, NSA/CSS Operations Travel Records. (i) Exemption. (A)

Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(18)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) Records maintained solely for statistical research or program evaluation purposes and which are not used to make decisions on the rights, benefits, or entitlement of an individual except for census records which may be disclosed under 13 U.S.C. 8 , may be exempt pursuant to 5 U.S.C. 552a(k)(4) . (ii) Authority. 5 U.S.C. 552a(k)(2) (k)(4). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would place the subject of an investigation on notice that they are under investigation and provide them with significant information concerning the nature of the investigation, thus resulting in a serious impediment to law enforcement investigations. (B) From subsections (d) and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding.

means the online repository for all information, guidance, policy, and requirements on handling CUI. Among other information, the CUI Registry identifies all approved CUI categories and subcategories, provides general descriptions for each, identifies the basis for controls, establishes markings, and includes guidance on handling procedures (see <https://www.archives.gov/cui>). * * * *

Federal information system means an information system (44 U.S.C. 3502(8)) used or operated by an agency, by a contractor of an agency, or by another organization on behalf of an agency. * * *

* * * Information system means a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information (44 U.S.C. 3502(8)). * * * * PART 3-IMPROPER BUSINESS PRACTICES AND PERSONAL CONFLICTS OF INTEREST 4. Amend section 3.104-4 by: a. Revising the section heading; b. Removing paragraph (c); c. Redesignating paragraph (b) as paragraph (c); d. Adding a new paragraph (b); e. Revising the newly redesignated paragraph (c); f. Revising paragraph (d); and g. Removing from paragraph (e)(1) the words ‘A contractor’ and adding ‘An offeror or contractor’ in its place. The revisions and additions read as follows: 3.104-4 Disclosure, protection, and marking of contractor information. * * * * (b)(1) The clause at 52.204-XX, Controlled Unclassified Information, directs offerors and contractors to indicate or otherwise identify any contractor bid or proposal information, contractor-attributable information, proprietary business information, and source selection information submitted to the Government. The contracting officer should consult with the contractor if the contracting officer is unsure whether information provided by the contractor falls into one of these categories. (2) Individuals responsible for preparing material that may be source selection information as described at paragraph (10) of the ‘source selection information’ definition in 2.101 must mark the cover page and each page that the individual believes contains source selection information with the legend ‘Source Selection Information-See FAR 2.101 and 3.104.’ Although the information in paragraphs (1) through (9) of the definition in 2.101 is considered to be source selection information whether or not marked, all reasonable efforts must be made to mark such material with the same legend. (c) Contractor bid or proposal information, contractor-attributable information, proprietary business information, and source selection information must be marked and protected from unauthorized disclosure in accordance with 4.403, 14.401, 15.207, applicable law, and regulations, including 32 CFR part 2002 . If the offeror or contractor submits information that could be controlled unclassified information (e.g.,

(F) From subsection (e)(8) because the requirement to serve notice on an individual when a record is disclosed under compulsory legal process could unfairly hamper law enforcement processes. It is the nature of law enforcement that there are instances where compliance with these provisions could

alert the subject of an investigation of the fact and nature of the investigation, and/or the investigative interest of intelligence or law enforcement agencies; compromise sensitive information related to national security; interfere with the overall law enforcement process by leading to the destruction of evidence, improper influencing of witnesses, fabrication of testimony, and/or flight of the subject; reveal a sensitive investigative or intelligence technique; or constitute a potential danger to the health or safety of law enforcement personnel, confidential informants, and witnesses. (G) From subsection (f) because requiring the Agency to grant access to records and establishing agency rules for amendment of records would compromise the existence of any criminal, civil, or administrative enforcement activity. To require the confirmation or denial of the existence of a record pertaining to a requesting individual may in itself provide an answer to that individual relating to the (printed page 14809) existence of an on-going investigation. The investigation of possible unlawful activities would be jeopardized by agency rules requiring verification of the record, disclosure of the record to the subject, and record amendment procedures. (H) From subsection (g) for compatibility with the exemption claimed from subsection (f), the civil remedies provisions of subsection (g) must be suspended for this record system. Because of the nature of criminal investigations, standards of accuracy, relevance, timeliness and completeness cannot apply to this record system. Information gathered in criminal investigations is often fragmentary and leads relating to an individual in the context of one investigation may instead pertain to a second investigation. (23) System identifier and name. DMDC 17 DoD, Continuous Evaluation Records for Personnel Security. (i) Exemption. In the course of carrying out records checks for continuous evaluation, exempt records from other systems of records may in turn become part of the case records maintained in this system. To the extent that copies of exempt records from those 'other' systems of records are maintained into this system, OSD claims the same exemptions for the records from those 'other' systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a

(4) The CSA may consider other circumstances that may affect an individual's eligibility to serve effectively including the number of boards on which the individual serves, the length of time serving on any other governance boards, and other factors in accordance with CSA-provided guidance. (5) Trustees, proxy holders, and outside directors must be determined eligible for access to classified information at the level of the entity eligibility determination for access to (printed page 83334) classified information. Individuals who are serving as trustees, proxy holders, or outside directors as part of a mitigation measure for the entity are not considered to have prior involvement solely by performing that role for purposes of paragraph (f)(3) of this section. (g) Government security committee (GSC). Under a VT, PA, SSA, or SCA, the contractor is required to establish a permanent committee of its board of directors, known as the GSC. (1) Unless otherwise approved by the CSA, the GSC consists of trustees, proxy holders, or outside directors and those officer directors who have been determined to be eligible for access to classified information. (2) The members of the GSC are required to ensure that the contractor adheres to laws and regulations and maintains internal entity policies and procedures to safeguard classified information entrusted to it. The GSC ensures that violations of those policies and procedures are promptly investigated and reported to the appropriate authority when it has been determined that a violation has occurred. (3) The contractor's FSO will be the principal advisor to the GSC and attend GSC meetings. The chairman of the GSC must concur with the appointment and replacement of FSOs selected by management. The FSO functions will be carried out under the authority of the GSC. (h) Additional procedures for FOCI mitigation or negation measures. In addition to the basic requirements of the FOCI mitigation or negation agreement, the entity may be required to document and implement additional procedures based upon the circumstances of an entity's operations. Those additional procedures will be established in supplements to the FOCI mitigation agreement to allow for flexibility as circumstances change without having to renegotiate the entire agreement. When making use of supplements, the CSA does not consider the FOCI mitigation measure final until the CSA has approved the required supplements. These supplements may include: (1) Technology control plan (TCP).

Federal Cybersecurity Awareness Programs ## Federal Cybersecurity Awareness Programs Prior industry surveys and research studies have revealed that organizational cybersecurity awareness (hereafter shortened to 'security awareness') programs may face a number of challenges, including lack of: leadership support; resources; and staff with sufficient background and skills to implement an effective and engaging program. However, no prior research has explored security awareness

programs specifically in the United States (U.S.) government (federal) sector. To address this gap, NIST conducted a two-phase, mixed methods research study to understand the needs, challenges, and practices of federal security awareness programs. This report describes the research background and methodology, along with the characteristics of the participants, organizations, and programs represented in the study. Research results can serve as a resource for federal security awareness professionals, managers, and organizational decision makers to improve and advocate for their organizations' security awareness programs. Results can also inform the development of federal security awareness guidance, policies, sharing forums, and initiatives meant to aid programs in becoming more effective. While focused on the U.S. government, findings may also have implications for organizational security awareness programs in other sectors.

From the NIST SP 800-172 Rev 3 Final Public Draft: The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 ii Audience 28 This publication serves a diverse group of individuals and organizations in the public and private sectors, including individuals with:

- System development life cycle responsibilities (e.g., program managers, mission/business owners, information owners/stewards, system designers and developers, system/security engineers, systems integrators)
- Acquisition or procurement responsibilities (e.g., contracting officers)
- System, security, or risk

Document the risk assessment results. Once the risk assessment has been completed as described above, the results of the risk assessment should be documented. Principally, the regulated entity should document all threat/vulnerability pairs (i.e., a scenario in which an identified threat can exploit a vulnerability) applicable to the organization, the likelihood and impact calculations, and the overall risk to ePHI for the threat/vulnerability pair. Regulated entities should consider sharing the risk assessment results with organizational leadership, whose review can be crucial to the organization's ongoing risk management. The Department has also published guidance that explains the differences between a risk analysis and a gap analysis, and the use of both in an entity's risk management program. [470] While a risk analysis is a comprehensive identification of risks and vulnerabilities to all ePHI, a gap analysis typically provides a partial assessment of an entity's enterprise and is often used to provide a high-level overview of what safeguards are in place (or missing) and may also be used to review a regulated entity's compliance with particular standards and implementation specifications of the Security Rule. Other NIST guidance on conducting risk assessments explains that the result of a risk analysis is a determination of risk posed to the regulated entity's ePHI and related information systems. [471] (printed page 940) Consistent with the discussion above, a key step is determining the risk level posed to such ePHI by threats and vulnerabilities and how critical it is to address and mitigate the identified risk. In general, the descriptive words ·very high· or ·critical· are used to indicate that a threat event could be expected to have multiple severe or catastrophic adverse effects on organizational operations, organizational assets, individuals, other organizations, or the country. [472] A ·high· risk would indicate that a threat event could be expected to have a severe or catastrophic adverse effect on the same, while a ·moderate· risk could indicate that the threat event could have a serious adverse effect on the same. Risks that are ·low· and ·very low· could be expected to have a limited and negligible effect, respectively, on organizational operations or assets, individuals, other organizations, or the country.

In general, location information provided to mobile applications will either be two- or three-dimensional. There are at least three factors that will influence to what extent public safety should use the location information being provided: accuracy, integrity, and confidentiality. Location information can be derived using various sources and techniques with each providing varying levels of accuracy. The integrity of the location information may need to be protected so that false location information is not provided that interferes with a timely response. Under certain circumstances, location information being generated may need to be kept confidential so as to not endanger public safety personnel. That said; seamless, efficient, and ubiquitous location communication stands to both empower and enrich public safety as they seek to fulfill their mission. Both public safety mobile application developers and users need to understand how accurate location information is and how that data is protected (integrity and confidentiality) in order to create and use applications in the most effective and secure manner.

1. What is considered sensitive data?
2. Is sensitive data sufficiently defined by legal/regulatory compliance requirements?
3. How is

sensitive data identified and labeled? 4. How is the type of data protection needed/required determined? 5. What types of data protection are needed/required? 6. What types of data need/require privacy protection? (such as personnel information, user/agency data)

(1) Document the policies and procedures required to comply with this subpart and how the covered entity or business associate considered the factors at § 164.306(b) in the development of such policies and procedures. (2) Document each action, activity, or assessment required by this subpart. (b) Implementation specifications (1) Time limit. Retain the documentation required by paragraph (a) of this section for 6 years from the date of its creation or the date when it last was in effect, whichever is later. (2) Availability. Make documentation available to those persons responsible for implementing the procedures to which the documentation pertains. (3) Updates. Review and update documentation at least once every 12 months and within a reasonable and appropriate period of time after a security measure is modified. § 164.318 Transition provisions. (a) Standard: Effect of prior contracts or other arrangements with business associates. Notwithstanding any other provisions of this subpart, a covered entity, or business associate with respect to a subcontractor, may allow a business associate to create, receive, maintain, or transmit electronic protected health information pursuant to a written contract or other arrangement with such business associate that does not comply with §§ 164.308(b) and 164.314(a), only in accordance with paragraph (b) of this section. (b) Implementation specification: Deemed compliance (1) Qualification. Notwithstanding other sections of this subpart, a covered entity, or business associate with respect to a subcontractor, is deemed to be in compliance with the documentation and contract requirements of §§ 164.308(b) and 164.314(a), with respect to a particular business associate relationship for the time period set forth in paragraph (b)(2) of this section, if both of the following apply: (i) Prior to [DATE OF PUBLICATION OF THE FINAL RULE IN THE Federal Register], such covered entity, or business associate with respect to a subcontractor, has entered into and is operating pursuant to a written contract or other written arrangement with the business associate that complies with the applicable provisions of §§ 164.308(b) and 164.314(a) that were in effect on such date. (ii) The contract or other arrangement is not renewed or modified from [DATE 60 DAYS AFTER DATE OF PUBLICATION OF THE FINAL RULE IN THE Federal Register], until [DATE 240 DAYS AFTER DATE OF PUBLICATION OF THE FINAL RULE IN THE Federal Register]. (2) Limited deemed compliance period. A prior contract or other arrangement that meets the qualification requirements at paragraph (b)(1) of this section shall be deemed compliant until the earlier of the following dates: (i) The date such contract or other arrangement is renewed on or after [DATE 240 DAYS AFTER DATE OF PUBLICATION OF THE FINAL RULE IN THE Federal Register]. (ii) [DATE 1 YEAR AND 60 DAYS AFTER DATE OF PUBLICATION OF THE FINAL RULE IN THE Federal Register]. (c) Covered entity and business associate responsibilities.

·Security,· a NISP CSA information collection, is assigned OMB Control Number: 1910-1800. This information collection, which includes facility security clearance information, is used by the DOE to exercise management, oversight, and control over its contractors' management and operation of DOE's Government-owned contractor-operated facilities, and over its offsite contractors. The contractor management, oversight, and control functions relate to the ways in which DOE contractors provide goods and services for DOE organizations and activities in accordance with the terms of their contracts and the applicable statutory, regulatory, and mission support requirements of the Department. Information collected from private industry and private individuals is used to protect national security and critical assets entrusted to the Department. (d) DoD collection. ·DoD Security Agreement,· is assigned OMB Control Number: 0704-0194. ·National Industrial Security System,· a CSA information collection, is assigned OMB Control Number: 0704-0571, and is a DoD information collection used to conduct its monitoring and oversight of contractors. Department of Defense ·Contract Security Classification Specification,· (available at: <https://www.esd.whs.mil/Portals/54/Documents/DD/forms/dd/dd0254.pdf> and available at: <https://www.dcsa.mil/is/nccs/>), is assigned OMB Control Number 0704-0567 and used by both DoD and agencies which have an industrial security agreement with DoD. ·Defense Information System for Security,· is assigned OMB Control Number: 0704-0573. Defense Information System for Security is a DoD automated system for personnel security, providing a common, comprehensive medium to record, document, and identify personal security actions within DoD including submitting adverse information, verification of security clearance status, requesting investigations, and supporting continuous evaluation activities. It requires personal data collection to facilitate the initiation, investigation and adjudication of information relevant to DoD security clearances and employment suitability (printed page 83320) determinations for active duty military, civilian employees and

contractors seeking such credentials. Joint Personnel Adjudicative System is assigned OMB Control Number: 0704-0496. Joint Personnel Adjudicative System is an information system which requires personal data collection to facilitate the initiation, investigation and adjudication of information relevant to DoD security clearances and employment suitability determinations for active duty military, civilian employees and contractors seeking such credentials. § 117.6 Responsibilities. (a) Under Secretary of Defense for Intelligence & Security (USD(I&S)). The USD(I&S), on behalf of the Secretary of Defense, and in accordance with E.O. 12829 , 32 CFR part 2004 , and DoDI 5220.22: (1) Carries out the direction in section 201 of E.O. 12829

), and allows DoD to consider the impact of supply chain risk in specified types of procurements related to national security systems. Section 806 defines supply chain risk as the risk that an adversary may sabotage, maliciously introduce unwanted function, or otherwise subvert the design, integrity, manufacturing, production, distribution, installation, operation, or maintenance of a covered system so as to surveil, deny, disrupt, or otherwise degrade the function, use, or operation of such system. II. Discussion and Analysis This DFARS change is necessary to implement the authorities provided to DoD by section 806, enabling DoD to establish a pilot program to mitigate supply chain risk, which is set to expire on September 30, 2018. These authorities are in addition to other available mitigations, which may not be adequate to protect against the malicious actions referred to in the definition of supply chain risk. Section 806 actions are permitted in procurements related to National Security Systems (NSS) (see 44 U.S.C. 3542(b)) that include a requirement relating to supply chain risk. This rule implements section 806's three supply-chain risk-management approaches as follows: (1) The exclusion of a source that fails to meet qualification standards established in accordance with the requirements of 10 U.S.C. 2319 , for the purpose of reducing supply chain risk in the acquisition of covered systems. (2) The exclusion of a source that fails to achieve an acceptable rating with regard to an evaluation factor providing for the consideration of supply chain risk in the evaluation of proposals for the award of a contract or the issuance of a task or delivery order. (3) The decision to withhold consent for a contractor to subcontract with a particular source or to direct a contractor for a covered system to exclude a particular source from consideration for a subcontract under the contract. The rule establishes a new provision and clause (see DFARS 239.7306) for inclusion in all solicitations and contracts, including contracts for commercial items or commercial off-the-shelf items involving the development or delivery of any information technology, whether acquired as a service or as a supply, because portions of these contracts may be used to support or link with one or more NSS. Another reason for including the provision and clause in all DoD solicitations and contracts for information technology is to manage the operational security risks of including the provision and clause only in procurements for very sensitive DoD procurements, thereby identifying those very procurements as a target for the risk section 806 aims to deter.

The Department of Homeland Security (DHS) is an especially important Federal actor that serves as a focal point for the security of cyberspace. It provides consolidated intrusion detection, incident analysis and cyber response capabilities to protect Federal agencies' external access points, including access to the Internet. While the Department of Defense (DOD) defends military and national security systems, DHS has the lead in securing federal civilian systems. DHS also works with public and private stakeholders to protect critical infrastructure and key resources (CIKR). [3] A number of entities within the Department of Justice, including the Federal Bureau of Investigation, as well as the United States Secret Service in DHS, track and prosecute cyber crimes. The National Science and Technology Council and its Committee on Technology serve as the coordinating organization over the Networking and Information Technology Research and Development (NITRD) program, which is the primary mechanism by which the U.S. Government coordinates its unclassified networking and IT research and development investments, including cybersecurity research and development. [4] The Department of Commerce has programs that complement and support these and other federal efforts. For example, the Department's National Institute of Standards and Technology (NIST) [5] develops standards and guides for securing non-national security Federal information systems. It defines minimum security requirements for federally held information and for information systems. NIST is also a primary contributor and member of the NITRD program, leading research and development in computer forensics tool testing, seamless mobility, trustworthy information systems, information security automation, combinatorial testing, next generation access control, and Internet infrastructure protection (with DHS funding). NIST also is responsible for the National Software Reference Library, National Vulnerability Database, and Security Content Automation Protocol. NIST identifies methods and metrics for assessing the

effectiveness of security requirements; evaluates private sector security policies for potential federal agency use; and provides general cybersecurity technical support and assistance to the private sector and federal agencies. Moreover, over the (printed page 44218) past two decades, the Department's National Telecommunications and Information Administration (NTIA), in its role as principal adviser to the President on telecommunications and information policies, has worked closely with other parts of government on broadband deployment, Internet policy development, securing the Internet namespace, and other issues. As an advocate for our nation's businesses, NTIA has played an instrumental role in developing policies that have helped commerce over the Internet flourish. [6]

The NIST Risk Management Framework (RMF), documented in NIST SP 800-37 Rev 2, provides a structured process for managing security and privacy risks. The RMF consists of seven steps: 1. ****Prepare****: Establish context and priorities 2. ****Categorize****: Determine information system impact level 3. ****Select****: Choose appropriate security controls 4. ****Implement****: Deploy the selected controls 5. ****Assess****: Evaluate control effectiveness 6. ****Authorize****: Accept residual risk (Authority to Operate) 7. ****Monitor****: Ongoing assessment and reporting While federal agencies use RMF directly, defense contractors implement a subset of RMF through NIST SP 800-171 and CMMC. Understanding RMF helps contractors appreciate the broader security framework their controls fit into.

From the NIST SP 800-172 Rev 3 Final Public Draft: recovery time, and reconstitution objectives; and organizational metrics consistent 1360 with contingency plan requirements. Reconstitution includes the deactivation of interim system capabilities that may have been needed during recovery operations. Reconstitution also includes assessments of fully restored system capabilities, the reestablishment of continuous monitoring activities, and activities to prepare the system and organization for future disruptions, breaches, compromises, or failures. Recovery and reconstitution capabilities can include automated mechanisms and manual procedures. Organizations establish recovery time and recovery point objectives as part of contingency planning. This requirement does not enhance a specific requirement in SP 800-171 but can be used to s

The CMMC implementation follows a phased approach: - Phase 1 (began November 10, 2025): DoD began incorporating CMMC requirements in applicable procurements via DFARS 252.204-7021. The first 12 months focus primarily on self-assessments. Phase 1 includes Level 1 (self-assessment) and Level 2 (self-assessment) for applicable contracts. - Phase 2 (scheduled November 10, 2026): Expands to include CMMC Level 2 requirements with both self-assessment and C3PAO certification assessments in solicitations and contracts. This is when third-party assessments become a contract requirement. - Full compliance: By October 31, 2026, CMMC compliance will be required for all new DoD contract awards involving CUI or FCI. Defense contractors should be preparing now for their target CMMC level, as the assessment pipeline is expected to be heavily subscribed once Phase 2 begins.

3.3.2 Authorization... 3.3.2 Authorization After verifying the identity of a remote access user, organizations may choose to perform checks involving the telework client device to determine which internal resources the user should be permitted to access.

(Comment 90) One comment states that some firms use carriers such as United Parcel Service, Federal Express, and the United States Postal Service to deliver their products and conduct all their transactions with these carriers via the Internet. The address and fax numbers of these carriers are not relevant. The comment requests that FDA revise the section on identifying information of the transporter to require only sufficient identifying information. (Response) FDA disagrees with this comment. In the event that FDA has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals, FDA would need to determine from the source and recipient records who transported the subject food to complete the tracing investigation. Although the transportation may be arranged over the Internet, companies such as those mentioned in the comment have fixed addresses, such as a corporate headquarters, that would need to be included in the record so that if FDA had to access their existing records under section §.1.361 of this final rule, FDA would know where to go. (Comment 91) One comment states that wines produced in France are sold by someone other than the producer and that the producer never knows the destination of the wine. The comment states that the recordkeeping requirement is an unnecessary burden on the producer because much of the producer's wine may be sent to destinations other than the United States. (Response) There is no requirement for a person that manufactures or processes food to know the ultimate destination of its product. A person subject to

subpart J of this final rule is only required to establish and maintain records to identify the transporter and nontransporter immediate previous sources and transporter and nontransporter immediate subsequent recipients of food. Further, FDA notes that it has excluded all foreign persons, except foreign persons who transport food in the United States, from all of the regulations in subpart J. (Comment 92) One comment requests clarification on the records requirements for products produced before the regulations take effect. (Response) Covered persons are required to establish and maintain records to identify the immediate previous sources and the immediate subsequent recipients of all food as of the compliance date of this final rule, keeping in mind the staggered compliance dates provided in § 1.368 of this final rule. If a food was received before the compliance date of this final rule, then there is no obligation to keep records of the immediate previous sources of that food. If a food is released on or after the compliance date of this final rule, you must establish and maintain records of the immediate (printed page 71597) subsequent recipients of the food, regardless of when that food was produced or received. 2. Information Reasonably Available to Identify the Specific Source of Each Ingredient

(Response) The business described in the comment is not treated differently than other retailers. Persons who distribute food to businesses do not qualify for the exclusion for sales to consumers in § 1.327(d) of the final rule. Thus, sales of food to restaurants require the establishment and maintenance of records of the immediate subsequent recipient, as codified in § 1.345 of the final rule, to the extent that information is reasonably available to you. Information is reasonably available to you if you have a system in place to capture the information. FDA does not intend to require the reconfiguration of business operations. Thus, for example, information is reasonably available to you when the purchaser has an established commercial account to which the food purchases are charged in an identifiable manner. Accordingly, § 1.327(e) of the final rule provides that persons who operate retail food establishments that distribute food to persons who are not consumers are subject to all of the requirements in subpart J of this final rule. However, the requirements in § 1.345 of the final rule to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients that are not consumers applies as to those transactions only to (printed page 71576) the extent the information is reasonably available. For purposes of this section, 'retail food establishment' is defined to mean an establishment that sells food products directly to consumers as its primary function. The term 'consumers' does not include businesses. A retail food establishment may manufacture/process, pack, or hold food if the establishment's primary function is to sell from that establishment food, including food that it manufactures/processes, packs, or holds, directly to consumers. A retail food establishment's primary function is to sell food directly to consumers if the annual monetary value of sales of food products directly to consumers exceeds the annual monetary value of sales of food products to all other buyers. A 'retail food establishment' includes grocery stores, convenience stores, and vending machine locations.

Use the clause at 252.204-70XX, Expediting Contract Closeout, in solicitations and contracts, including solicitations and contracts using FAR part 12 procedures for the acquisition of commercial items, when the contracting officer intends to expedite contract closeout through the waiver of entitlement to any residual dollar amounts by the contractor and the Government at the time of final contract closeout. PART 212-ACQUISITION OF COMMERCIAL ITEMS 3. Amend section 212.301 by adding paragraph (f)(ii)(K) to read as follows: 212.301 Solicitation provisions and contract clauses for the acquisition of commercial items. (f) * * * (ii) * * * (K) Use the clause at 252.204-70XX, Expediting Contract Closeout, as prescribed in 204.804-70. * * * * * PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 4. Add section 252.204-70XX to read as follows: 252.204-70XX Expediting contract closeout. As prescribed in 204.804-70, use the following clause: Expediting Contract Closeout (DATE) (a) Both the Government and the Contractor agree to waive any entitlement that otherwise might accrue to either party in any residual dollar amount of \$1,000 or less at the time of final contract closeout. (b) A residual dollar amount includes all money owed to either party at the end of the contract and as a result of the contract, excluding amounts connected in any way with taxation or a violation of law or regulation. (c) For purposes of determining residual dollar amounts, offsets (for example across multiple contracts or orders) may be considered to the extent permitted by law. (End of clause) [FR Doc. 2020-06724 Filed 4-7-20; 8:45 am] BILLING CODE 5001-06-P

) to presume that a regulated entity had implemented reasonable and appropriate compensating controls where the regulated entity has implemented the security measures prescribed and as

instructed by the FDA-authorized label for the device. The proposed language recognizes that while the device's label may not specifically require deployment of an MFA solution, it may provide for a specific compensating control and the manner in which that control is to be implemented. This would include any updates, such as patches, recommended or required by the manufacturer of the device. While not required, a regulated entity would be permitted to implement additional alternative security measures and compensating controls in accordance with best practices and/or its risk analysis. Additionally, the Department proposes at 45 CFR 164.312(f)(2)(iv)(B) (3) that during any period in which compensating controls are in use, the regulated entity's Security Official would be required to review the effectiveness of the compensating controls at securing its relevant electronic information systems. While regulated entities should review implemented compensating controls on a routine basis, the Department intends for a regulated entity to periodically review the implementation and effectiveness of implemented compensating controls to ensure the continued protection of ePHI. [788] For example, if a regulated entity's plan to migrate ePHI from hardware that does not support MFA changes such that the use of the non-MFA hardware continues for a longer period of time, the regulated entity should review implemented compensating controls to ensure ongoing effectiveness and whether new compensating controls should be implemented. We are proposing to require that the review be conducted at least once every 12 months or in response to an environmental or operational change, whichever is more frequent, and that the review be documented. Additionally, the Department proposes to require that the review be documented. If the regulated entity's Security Official review determines that certain compensating controls are no longer effective, the Department would expect the regulated entity to adopt other compensating controls that are effective to continue to meet the applicable proposed exception. As an example of how proposed 45 CFR 164.312(f)(2)(iii) would operate in concert with proposed 45 CFR 164.312(f)(2)(iv) , a regulated entity experiencing an emergency that adversely affects a relevant electronic information system and renders MFA infeasible would be required to document the following: The regulated entity has experienced an emergency that has adversely affected a relevant electronic information system, including the nature of the emergency and the specific circumstances that adversely affected the specific electronic information system. MFA has been rendered infeasible with respect to the specific relevant electronic information system adversely affected by the emergency.

3.3.3 Use Case 3: Sharing Data with Contractor... 3.3.3 Use Case 3: Sharing Data with Contractor A user wants to provide a contractor with copies of large data sets on a daily basis because the contractor has no direct access to the system containing the data.

In the following table, costs, food safety benefits, and cost effectiveness measures are reported for each of the coverage options described in the above table, and the final rule. Costs are reported in terms of annualized costs and incremental costs using a 7-percent discount rate over a 20-year horizon. Benefits are reported in terms of the annual number of food safety illnesses averted (reported and unreported), and the incremental number of illnesses averted. The estimates of the numbers of averted illnesses should be interpreted as minimum values because they relate to only the food safety benefits; bioterrorism considerations are not incorporated into the estimates. Cost effectiveness measures are in terms of the incremental costs per averted illness, and the average cost per averted illness. The incremental cost per averted illness is used to measure the relative cost effectiveness of an option when compared with successively more stringent requirements. It is computed by dividing the incremental costs from the option by the incremental benefits. Since option H averts a larger number of illnesses at lower cost than options A through F, option H dominates the other options and they can be eliminated from further consideration in an incremental cost effectiveness analysis. Thus, the cells for computing the incremental costs per averted illness for those options are left blank in table 18 of this document. Similarly, through the principle of weak (or extended) dominance, option I can be eliminated from the incremental cost effectiveness analysis. (For a full discussion of extended dominance in cost-effectiveness analysis, see Gold, M.L., J.E. Siegel, L.B. Russell, and M.C. Weinstein, · Cost Effectiveness in Health and Medicine: The Report of the Panel on Cost-Effectiveness in Health and Medicine, Oxford University Press, · New York, p. 286, 1996). Consequently, only options H, the final rule, and the adjusted comprehensive coverage are used to measure the incremental cost effectiveness. We assume that bioterrorism considerations would not alter the relative order of the number of illnesses averted across all options. The average costs per averted illness reported in table 18 of this document are calculated by dividing the annualized costs by the total number of illnesses averted for each option. The average costs per averted illness is the cost-effectiveness of each option relative to the baseline.

For the final rule, the average cost-effectiveness expressed in costs per illness prevented is \$110,000 discounted at 7 percent and \$108,000 discounted at 3 percent. Table 18. Costs, Food Safety Benefits, and Cost Effectiveness of Alternative Coverage Options

	Costs	Benefits	Cost Effectiveness
Annualized Costs	Incremental Cost	Illnesses averted	Incremental Benefit
Incremental Cost per Averted Illness	Average Cost per Averted Illness	Option A	\$40,975,852 245
\$167,248	Option C	\$56,753,102 316	\$179,598
	Option D	\$67,712,296 355	\$190,739
\$69,902,094 359	Option E	\$194,713	Option B

(E) Overall Level 2 self-assessment score (e.g., 105 out of 110). (F) POA&M usage and compliance status, if applicable. (ii) Conditional Level 2 (Self). The OSA has achieved the CMMC Status of Conditional Level 2 (Self) if the Level 2 self-assessment results in a POA&M and the POA&M meets all the CMMC Level 2 POA&M requirements listed in §170.21(a)(2). (A) Plan of Action and Milestones. A Level 2 POA&M is allowed only in accordance with the CMMC POA&M requirements listed in §170.21. (B) POA&M closeout. The OSA must remediate any NOT MET requirements, must perform a POA&M closeout self-assessment, and must post compliance results to SPRS within 180 days of the CMMC Status Date associated with the Conditional Level 2 (Self). If the POA&M is not successfully closed out within the 180-day timeframe, the Conditional Level 2 (Self) CMMC Status for the information system will expire. If Conditional Level 2 (Self) CMMC Status expires within the period of performance of a contract, standard contractual remedies will apply, and the OSA will be ineligible for additional awards with a requirement for the CMMC Status of Level 2 (Self), or higher requirement, for the information system within the CMMC Assessment Scope until such time as a new CMMC Status is achieved. (iii) Final Level 2 (Self). The OSA has achieved the CMMC Status of Final Level 2 (Self) if the Level 2 self-assessment results in a passing score as defined in §170.24. This score may be achieved upon initial self-assessment or as the result of a POA&M closeout self-assessment, as applicable. (iv) CMMC Status investigation. The DoD reserves the right to conduct a DCMA DIBCAC assessment of the OSA, as provided for under the 48 CFR 252.204-7020 . If the investigative results of a subsequent DCMA DIBCAC assessment show that adherence to the provisions of this part have not been achieved or maintained, these DCMA DIBCAC results will take precedence over any pre-existing CMMC Status. At that time, standard contractual remedies will be available and the OSA will be ineligible for additional awards with CMMC Status requirement of Level 2 (Self), or higher requirement, for the information system within the CMMC Assessment Scope until such time as a new CMMC Status is achieved. (2) Affirmation. Affirmation of the Level 2 (Self) CMMC Status is required for all Level 2 self-assessments at the time of each assessment, and annually thereafter. Affirmation procedures are set forth in §170.22. (b) Contract eligibility. Prior to award of any contract or subcontract with requirement for CMMC Status of Level 2 (Self), the following two requirements must be met: (1) The OSA must achieve, as specified in paragraph (a)(1) of this section, a CMMC Status of either Conditional Level 2 (Self) or Final Level 2 (Self). (2) The OSA must submit an affirmation of compliance into SPRS, as specified in paragraph (a)(2) of this section. (c) Procedures .(1) Level 2 self-assessment of the OSA.

te risk response, and communicate risk activities as part of an enterprise CSRM strategy. - NISTIR 8286C describes processes for aggregating information from CSRM activities throughout the enterprise. As that information is integrated and harmonized, organizational and enterprise leaders monitor achievement of risk objectives, consider any changes to risk strategy, and use the combined information to maintain awareness of risk factors and positive risks (or opportunities).

DFARS 252.204-7012 (Safeguarding Covered Defense Information and Cyber Incident Reporting) Core CUI protection clause requiring NIST SP 800-171 implementation, cyber incident reporting within 72 hours, and preservation of evidence. Non-compliance with 252.204-7012 can result in: loss of contract eligibility, termination for cause, False Claims Act liability (if contractor misrepresented compliance status), suspension or debarment from future DoD contracting, and in cases involving CUI spillage or breach, potential civil or criminal penalties.

on new, amended, altered, or deleted systems of records to inform the public of the Privacy Act systems of records that it maintains. The Privacy Act requires submission of new or significantly changed systems of records to OMB and both houses of Congress before publication in the Federal Register (See Appendix E of this part). (2) Systems managers must send a proposed notice at least 120 days before implementing a new, amended or altered system to the DA Freedom of Information and Privacy Office. The proposed or altered notice must include a narrative statement and supporting documentation. A narrative statement must contain the following items: (i) System identifier and

name; (ii) Responsible Official, title, and phone number; (iii) If a new system, the purpose of establishing the system or if an altered system, nature of changes proposed; (iv) Authority for maintenance of the system; (v) Probable or potential effects of the system on the privacy of individuals; (vi) Whether the system is being maintained, in whole or in part, by a contractor; (vii) Steps taken to minimize risk of unauthorized access; (viii) Routine use compatibility; (ix) Office of Management and Budget information collection requirements; and (x) Supporting documentation as an attachment. Also as an attachment should be the proposed new or altered system notice for publication in the Federal Register . (3) An amended or altered system of records is one that has one or more of the following: (i) A significant increase in the number, type, or category of individuals about whom records are maintained; (ii) A change that expands the types of categories of information maintained; (iii) A change that alters the purpose for which the information is used; (iv) A change to equipment configuration (either hardware or software) that creates substantially greater access to the records in the system of records; (v) An addition of an exemption pursuant to Section (j) or (k) of the Act; or (vi) An addition of a routine use pursuant to 5 U.S.C. 552a(b)(3) . (4) For additional guidance contact the DA FOIA/P Office. (5) On behalf of DA, the Defense Privacy Office maintains a list of DOD Components' Privacy Act system of records notices at the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy> . (6) DA PAM 25-51 sets forth procedures pertaining to Privacy Act system of records notices. (7) For new systems, system managers must establish appropriate administrative, technical, and physical safeguards to ensure the security and confidentiality of records. This applies to all new systems of records whether maintained manually or automated.

title 32 of the Code of Federal Regulations , with the following new sections: Section 236.2 establishes the definitions of terms used in the new part, leveraging established definitions to the maximum extent possible (e.g., those provided in the Committee on National Security Systems Instruction No. 4009, "National Information Assurance Glossary") (http://www.cnss.gov/Assets/pdf/cnssi_4009.pdf); Section 236.4 sets forth the basic requirements and procedures of the voluntary program, including information collection requirements; Section 236.5 characterizes cyber security information sharing and collection procedures; Section 236.6 establishes the general provisions of the voluntary DIB CS/IA program; and Section 236.7 sets forth the eligibility (printed page 27617) requirements to participate in the voluntary program. Nothing in this rule or program is intended to be inconsistent with any other related or similar federal agency or private sector activity or requirement. For example, nothing in this rule or program abrogates the Government's or the DIB participants' rights or obligations regarding the handling, safeguarding, sharing, or reporting of information, or regarding any physical, personnel, or other security requirements, as required by law, regulation, policy, or a valid legal contractual obligation. Similarly, this rule and program are intended to be consistent and coordinated with, and updated as necessary to ensure consistency with and support for, other federal activities related to the handling and safeguarding of controlled unclassified information, such as those that are being led by the National Archives and Records Administration pursuant to Executive Order 13556 "Controlled Unclassified Information" (November 4, 2010) (see <http://www.archives.gov/cui/>). Executive Orders 12866, "Regulatory Planning and Review" and 13563, "Improving Regulation and Regulatory Review" . It has been certified that 32 CFR part 236 does not: (a) Have an annual effect on the economy of \$100 million or more, or adversely affect in a material way, the economy; a section of the economy; productivity; competition; jobs; the environment; public health or safety; or State, local, or tribal governments or communities; (b) Create a serious inconsistency, or otherwise interfere with, an action taken or planned by another Agency; (c) Materially alter the budgetary impact of entitlements, grants, user fees, or loan programs, or the rights and obligations of recipients thereof; or (d) Raise novel legal or policy issues arising out of legal mandates, the President's priorities, or the principles as set forth in these Executive Orders. Public Law 104-121 , "Congressional Review Act" (5 U.S.C. 801) It has been determined that 32 CFR part 236 is not a "major" rule under 5 U.S.C. 801 , enacted by Public Law 104-121

In addition, a foreign comment states that meat, poultry, and eggs are exempt under the proposed rule because the United States deems current risk management systems associated with these products to be sufficiently stringent. The comment states that, in Australia, these products are subject to strict regulatory and certification requirements as "prescribed goods" under Australian legislation (the Export Control Act 1982), which the USDA audits. A range of other Australian products, such as milk and fish, are also prescribed goods and are subject to the same certification process. The comment, therefore, argues that all prescribed goods should qualify for an exemption on these

grounds. (Response) The rule does not impose any requirements with regard to food to the extent it is within USDA's exclusive jurisdiction under FMIA, PPIA, or EPIA. Under the FMIA, USDA regulates cattle, sheep, swine, equines, goats, and meat food products. Under the PPIA, USDA regulates poultry and poultry products. Under the Egg Products Inspection Act, USDA regulates some eggs and egg products. Any person that manufactures, processes, packs, transports, distributes, receives, holds, or imports some foods subject to exclusive USDA jurisdiction is exempt from these regulations with respect to that food while it is under USDA's exclusive jurisdiction. FDA has decided not to attach an appendix to the final rules highlighting which foods are within the scope of this final rule. If questions remain, FDA will determine whether it needs to issue additional guidance on this subject. With respect to the comment regarding Australian meat, poultry, eggs, milk, and fish, FDA notes that all foreign persons, except for foreign persons who transport food in the United States, are excluded from all of the requirements of the final rule under § 1.327(h). However, domestic persons who import these foreign products are required to comply with these recordkeeping regulations to the extent that they are FDA-regulated food products. (Comment 55) One foreign comment requests that FDA identify the list of persons that are excluded from all or part of the regulation in accordance with § 1.327. (Response) Foreign persons, except for foreign persons who transport food in the United States, are excluded from all of the requirements of this final rule under § 1.327(h). The term person includes an individual, partnership, corporation, and association (section 201 of the FD&C Act (21 U.S.C. 321(e)).

8. Foreign Facilities if Food Undergoes Further Manufacturing/Processing There were no comments received on this issue. However, FDA has decided to exempt foreign persons, except foreign persons who transport food in the United States, from this rulemaking. This is discussed in detail under section III.C of this document entitled Comments on Who is Subject to This Subpart? (Proposed § 1.326).

9. Pet Food

Cryptographically-protected passwords use salted one-way cryptographic hashes of passwords. See NIST Cryptographic Standards and Guidelines. FURTHER DISCUSSION All passwords must be cryptographically protected using a one-way function for storage and transmission. This type of protection changes passwords into another form, or a hashed password. A one-way transformation makes it theoretically impossible to turn the hashed 116 NIST SP 800-171A, pp. 34-35. 117 NIST SP 800-171 Rev. 2, pp. 25-26. IA.L2-3.5.10 Cryptographically-Protected Passwords CMMC Assessment Guide Level 2 | Version 2.13 133 password back into the original password, but inadequate complexity (IA.L2-3.5.7) may still facilitate offline cracking of hashes. Example You are responsible for managing passwords for your organization. You protect all passwords with a one-way transformation, or hashing, before storing them. Passwords are never transmitted across a network unencrypted [a,b]. Potential Assessment Considerations Are passwords prevented from being stored in reversible encryption form in any company systems [a]? Are passwords stored as one-way hashes constructed from passwords [a]? KEY REFERENCES NIST SP 800-171 Rev. 2 3.5.10

The PIA provides detailed procedures for handling personally identifiable information (PII), attributional information about the strengths or vulnerabilities of specific covered contractor information systems, information providing a perceived or real competitive advantage on future procurement action, and contractor information marked as proprietary or commercial or financial information. In addition, personnel information is covered by Office of the Secretary of Defense (OSD) System of Records Notice (SORN) DCIO 01 (<https://dpcl.d.defense.gov/Portals/49/Documents/Privacy/SORNs/OSDJS/DCIO-01.pdf>). No changes to the PIA or SORN are being proposed in conjunction with this proposed rule. Expected Impact of the Proposed Rule Costs DoD believes the cost impact of the proposed changes to this proposed rule is not significant, as the changes primarily expand the availability of the established DIB CS Program to additional defense contractors. The newly eligible population of defense contractors may incur costs to familiarize themselves with the rule and those who elect to participate in the program will incur costs related to program participation. The Government will continue to incur costs related to operating the program. The DIB CS Program conducts outreach activities to defense contractors through press releases, participation in defense-oriented conferences, speaking engagements, and through digital media. The program will leverage pre-established channels to message changes to the program and engage with the eligible population of defense contractors. Based on the program growth experienced that during the last phase of program expansion the program is forecasting annual growth at just over 1% of the eligible population. At a growth rate of 1% per year it will take the program approximately 10 years to achieve the estimated 10% participation rate of the eligible DIB. Costs to DIB Participants In order to join the DIB CS Program there is an initial labor burden for a defense contractor to familiarize themselves with the rule and

subsequently apply to the program and provide POC information. In total, if it takes each contractor 30 minutes to read and familiarize him/herself with the rule, it will take contractors 4,000 hours to familiarize themselves with the rule (8,000 participants $\times$.5 = 4,000 hours). At an hourly wage of \$108.92, the total cost incurred by contractors for rule familiarization will amount to \$108,920 dollars ($\$108.92 \times .5 \text{ hours} = \$54.46 \times 4,000 \text{ hours} = \$217,840$). The hourly labor cost is based on the mean wage estimate from the Bureau of Labor Statistics for an Information Security Analysts, Occupational Employment and Wages, May 2021 and is covered under information collection 0704-0490. This hourly wage is adjusted upward by 100% to account for overhead and benefits, which implies a value of \$108.92 per hour.

Organizations that experience cybersecurity attacks can experience reputational harm and other monetary costs, such as those associated with providing breach notifications, paying fines to regulators and damages to individuals, and providing credit monitoring and identity theft-related services. [980] The harm to an organization's reputation is difficult to quantify, but it can also affect the quality of care administered to individuals. [981] Privacy and security of ePHI are paramount to individuals feeling safe and at ease sharing their IIHI with clinicians. Security breaches can negatively impact a patient's confidence in a health care organization if they believe their information and privacy may be compromised. This can cause them to delay seeking treatment or (printed page 1003) withhold information from health care practitioners, ultimately compromising the decision-making capacity of their health care provider to administer the best quality of care. [982] Decreasing the number and scope of health care breaches would reduce the harms of such breaches and would be a significant benefit of the proposals in the NPRM. 5. Comparison of Benefits and Costs Key inputs to the estimation of costs of this proposed rule include the numbers of regulated entities and health plan sponsors. The Department has not previously quantified the costs of Security Rule compliance for health plan sponsors because the existing requirements are for plan documents to require such sponsors to implement administrative, physical, and technical safeguards, but not necessarily to comply with the specific requirements of the Security Rule. Therefore, the proposed requirement to comply with the proposed changes to the Security Rule, along with the number of affected plan sponsors (approximately 740,000), results in a significant increase in overall cost estimates compared to the existing rule. The benefits of improved security for ePHI accrue to individuals, regulated entities, and health plan sponsors and are significant. The Department has discussed the benefits above. The Department seeks to reduce the risk and mitigate the effects of breaches of ePHI and related information systems through the proposals included in this NPRM. Because the frequency and magnitude of cybersecurity events are inherently difficult to predict, we chose to conduct a break-even analysis in lieu of a cost savings analysis. The Department solicits comments with any information and data on the incidence and negative consequences of cybersecurity breaches.

A number of organizations have established Supply Chain Risk Councils (or Supply Chain Leadership Risk Councils) that include executives from supply chain/procurement, information technology, cybersecurity, operations, legal, enterprise risk management (ERM), and other functional and leadership areas of the organization, depending on the organization's business and structure. These Councils proactively review relevant risks and risk mitigation plans, set priorities, direct sharing of best practices throughout the enterprise, and pilot initiatives. They also result in informal networks of leaders that facilitate trust and accountability in complex business environments. The benefit of Councils is the shared risk decision-making that ensures all perspectives are addressed. A formal C-SCRM program ensures organizational accountability for managing cyber supply chain risks. Mature organizations have formal programs with established governance, policies and procedures, processes, and tools.

The final rule revises DFARS 204.7602, Applicability, to align with the solicitation provision prescription at DFARS 204.7604 and the stated intent of the rule to move the coverage from part 213 to a new subpart 204.76, as described in the preamble of the proposed rule. Section 204.7602 states that use of SPRS risk assessments is required for the evaluation of quotations or offers in response to solicitations for supplies and services, including solicitations using FAR part 12 procedures for the acquisition of commercial products and commercial services. DFARS 204.7602, as revised, does not limit applicability of use of SPRS risk assessments to acquisitions using FAR part 13 simplified acquisition procedures; therefore, the recommended change to the solicitation provision prescription at DFARS 204.7604 will not be made. The solicitation provision is prescribed for use in solicitations for supplies and services, including solicitations using FAR part 12 procedures for

the acquisition of commercial products and commercial services. To clarify that the provision also applies to solicitations using FAR part 13 simplified acquisition procedures, the rule revises the language in part 213 at 213.106-2, paragraph (b)(i), to provide a cross-reference to 204.7603 and to require contracting officers to consider SPRS risk assessments as a basis of award for solicitations using FAR part 13 simplified acquisition procedures, and obsolete language is removed. Further, to more clearly reflect that the intended purpose of the provision extends beyond FAR part 13 actions, the provision title is revised to read as follows: 252.204-7024, Notice on the Use of the Supplier Performance Risk System. The proposed rule, at sections I. and II. of the preamble, stated that SPRS is required to be used to evaluate quotes and offers received under all solicitations for supplies and services. To further clarify applicability of the procedures at DFARS 204.7603 to Federal Supply Schedules, commercial acquisitions, acquisitions using FAR part 13 simplified acquisition procedures, evaluation of offers under part 215, and indefinite-delivery contracts, cross-references to DFARS 204.7603 are added to Subpart 208.4, Federal Supply Schedules; Subpart 212.2, Special Requirements for the Acquisition of Commercial Products and Commercial Services; Subpart 213.1, Procedures; 215.3, Source Selection; and Subpart 216.5, Indefinite-Delivery Contracts. b. SPRS Website Comment: One respondent commented that Government-Industry Data Exchange Program (GIDEP) alerts are not appropriate measures of quality performance and such data cannot be accurately translated into meaningful risk scores without dissecting each GIDEP report, including supplier letters and enclosures. Response:

. In exercising these authorities, the Government may consider information, public and non-public, including all-source intelligence, relating to an offeror and its supply chain. (c) If the Government exercises the authority provided in section 806 of Pub. L. 111-383 to limit disclosure of information, no action undertaken by the Government under such authority shall be subject to review in a bid protest before the Government Accountability Office or in any Federal court. (End of provision) 11. Add section 252.239-7018 to read as follows: 252.239-7018 Supply chain risk. As prescribed in 239.7306(b), use the following clause: SUPPLY CHAIN RISK (NOV 2013) (a) Definitions. As used in this clause Information technology (see 40 U.S.C 11101(6)) means, in lieu of the definition at FAR 2.1, any equipment, or interconnected system(s) or subsystem(s) of equipment, that is used in the automatic acquisition, storage, analysis, evaluation, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information by the agency. (1) For purposes of this definition, equipment is used by an agency if the equipment is used by the agency directly or is used by a contractor under a contract with the agency that requires (i) Its use; or (ii) To a significant extent, its use in the performance of a service or the furnishing of a product. (2) The term information technology includes computers, ancillary equipment (printed page 69273) (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources. (3) The term information technology does not include any equipment acquired by a contractor incidental to a contract. Supply chain risk means the risk that an adversary may sabotage, maliciously introduce unwanted function, or otherwise subvert the design, integrity, manufacturing, production, distribution, installation, operation, or maintenance of a national security system (as that term is defined at 44 U.S.C. 3542(b)) so as to surveil, deny, disrupt, or otherwise degrade the function, use, or operation of such system. (b) The Contractor shall maintain controls in the provision of supplies and services to the Government to minimize supply chain risk. (c) In order to manage supply chain risk, the Government may use the authorities provided by section 806 of Public Law 111-383 . In exercising these authorities, the Government may consider information, public and non-public, including all-source intelligence, relating to a Contractor's supply chain. (d) If the Government exercises the authority provided in section 806 of Public Law 111-383

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. Numerous panelists noted that consumers are widely adopting IoT devices and that IoT use within federal agencies is growing rapidly. The General Services Administration (GSA) has identified over

75 makes and 210 distinct models of IoT devices deployed in facilities they manage, spanning a broad range of IoT related services. IoT devices support many kinds of services that include network-connected surveillance equipment, irrigation control systems, physical access control systems, lighting control systems, and various types of environmental measuring systems, among others. 3 NIST SP 1900-202, Cyber-Physical Systems and Internet of Things, focuses on the meanings of the phrases 'cyber-physical systems' (CPS) and 'Internet of Things' (IoT), and on the relationship between them. This document examines 31 definitions for CPS and 30 definitions for IoT.

Patients and communities have a critical need for health care providers, including rural hospitals and other rural health care providers, to be resilient and remain operational, which depends in part on the cybersecurity of their electronic information systems. For rural health care providers, especially hospitals, a breach can significantly affect an entire community. [306] Rural health care providers often are separated by significant distances, which can have real consequences for someone experiencing a medical emergency. [307] A recent study comparing hospital characteristics and operations of rural and urban hospitals that experienced ransomware attacks between 2016 and 2021 found that rural hospitals experienced large declines in inpatient admissions and Medicare revenue, similar to those experienced by urban hospitals. [308] The study also found that the decline in volume and revenue of hospital outpatient and emergency room visits was more pronounced among rural facilities. [309] In fact, in June 2023, a hospital in rural Illinois announced that it would close, in part because a 2021 cyberattack prevented it from submitting claims to health plans for months. [310] According to a local elected official, the hospital's closure would require some residents to travel approximately 30 minutes for the nearest emergency room and obstetrics services. [311] Thus, implementing security measures to maintain facility operations is critical to minimize or avoid disruptions to patient care and patient safety activities in such facilities. Consistent with these examples, the Department believes that small and rural health care providers are also viewed as potential targets by cybercriminals, and such providers need to implement strong cybersecurity measures to secure the ePHI in their possession. In fact, in June 2024, the Administration announced a collaboration with the private sector to provide additional cybersecurity resources for rural health care providers in recognition of the importance of protecting the security of ePHI created, received, maintained, or transmitted by such entities. [312] We believe this collaboration will provide small and rural health care providers with additional support, particularly when coupled with other resources described in greater detail below. [313] Thus, we believe that small and rural health care providers have both the need to comply with the proposals in this NPRM and the capability of doing so. Additionally, we believe that the NPRM would continue to provide all regulated entities, including small and rural health care providers, the ability to take into account their circumstances when determining which security measures are reasonable and appropriate. [314] 5. A Strengthened Security Rule Is Critical to an Efficient and Effective Health Care System While the Security Rule generally continues to accomplish a primary goal of HIPAA, [315]

discussion. Shorter, more focused papers are encouraged and will be reviewed like any other paper. If you only need 2 or 4 pages (plus references) to clearly explain your work or idea, please submit a paper of that length. Reviewers will be instructed to assess the value of the talk to the workshop audience irrespective of the paper length; however, we stress again that the presentation should be sufficiently thorough for reviewers to make this evaluation.

plication Scheduling) that are all performed by multiple tools are incorporated - As depicted in Figure 1, the security functional layer spans all functional layers of the container technology stack. The security solutions covering these layers, however, must be implemented through the following components: - (a) Physical Host (i.e., hardware, since container hosting on VMs is out of scope for this document) - (b) Container OS (Host OS) interfaces - (c) Container Runtime interfaces - (d) Image Management and Registry Interfaces - (e) Orchestrator Interfaces

ows into the network. If the sensor registers activities that should be blocked, it indicates that the firewall is not configured securely. One limitation to network sniffing is the use of encryption. Many attackers take advantage of encryption to hide their activities-while assessors can see that communication is taking place, they are unable to view the contents. Another limitation is that a network sniffer is only able to sniff the traffic of the local segment where it is installed. This requires the assessor to move it from segment to segment, install multiple sniffers throughout the network, and/or use port spanning. Assessors may also find it challenging to locate an open

physical network port for scanning on each segment. In addition, network sniffing is a fairly labor-intensive activity that requires a high degree of human involvement to interpret network traffic.

(4) Raise novel legal or policy issues arising out of legal mandates, the President's priorities, or the principles set forth in this Executive Order. Section 202, Public Law 104-4, Unfunded Mandates Reform Act. It has been certified that 32 CFR part 286 does not contain a Federal mandate that may result in expenditure by State, local and tribal governments, in aggregate, or by the private sector, of \$100 million or more in any one year. Public Law 96-354, Regulatory Flexibility Act (5 U.S.C. 601) It has been certified that 32 CFR part 286 is not subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would not, if promulgated, have a significant economic impact on a substantial number of small entities. Public Law 96-511, Paperwork Reduction Act (44 U.S.C. Chapter 35) It has been certified that 32 CFR part 286 does not impose reporting or recordkeeping requirements under the Paperwork Reduction Act of 1995. List of Subjects in 32 CFR Part 286 Freedom of information Accordingly, 32 CFR part 286 is proposed to be revised to read as follows: PART 286-DOD FREEDOM OF INFORMATION ACT (FOIA) PROGRAM REGULATION Subpart A-General Provisions 286.1 286.2 286.3 286.4 Subpart B-FOIA Reading Rooms 286.7 286.8 286.9 286.10 Subpart C-Exemptions 286.13 286.14 Subpart D-FOIA Request Processing 286.17 286.18 286.19 286.20 286.21 Subpart E-Fee Schedule 286.24 286.25 286.26 286.27 Subpart F-Education and Training 286.30 286.31 Appendix A to Part 286-DoD FOIA Program Components Appendix B to Part 286-Addressing FOIA Requests Authority: 5 U.S.C. 552 . Subpart A-General Provisions §-286.1 Purpose. This part promotes uniformity in the DoD FOIA Program. It shall take precedence over all DoD Component publications that supplement and implement the DoD FOIA Program. A list of the DoD FOIA Program Components is at Appendix A to this part. §-286.2 Definitions. The following terms and meanings shall apply for the purposes of this part: Administrative appeal. A request by a member of the public, made under the FOIA, asking the appellate authority of the DoD Component to reverse any adverse determination by an Initial Denial Authority (IDA). A requester may also appeal the failure of an agency to respond within the statutory time limits. Adverse determination. A decision by an IDA to withhold all or part of a requested record, deny a fee category claim by a requester, deny a request for waiver or reduction of fees, deny a request to review an initial fee estimate, deny a request for expedited processing, confirm that no records were located during the initial search, or any determination that a requester believes is adverse in nature. Agency record.

·To DoD officers and employees who have a need for the record in the performance of their official duties. This is the ·official need to know· concept. (B) 5 U.S.C. 552a(b)(2) ·FOIA requires release of the information pursuant to 5 U.S.C. 552 . (C) 5 U.S.C. 552a(b)(3) ·For an authorized Routine Use, i.e. the ·Routine Use Exception.· The Routine Use must be listed in the applicable system of records notice published in the Federal Register and the purpose of the disclosure must be compatible with the purpose for the published Routine Use. (D) 5 U.S.C. 552a(b)(4) ·To the Bureau of the Census to plan or carry out a census or survey, or related activity pursuant to Title 13 of the U.S. Code. (E) 5 U.S.C. 552a(b)(5) ·To a recipient who has provided the Department of the Army or DoD with advance adequate written assurance that the record will be used solely as a statistical research or reporting record, and the record is to be transferred in a form that is not individually identifiable. (F) 5 U.S.C. 552a(b)(6) ·To the National Archives and Records Administration as a record that has sufficient historical or other value to warrant its continued preservation by the U.S. Government, or for evaluation by the Archivist of the United States or the designee of the Archivist to determine whether the record has such value. Note 1 to paragraph (h)(3)(iii)(F). Records transferred to the Federal Records Centers for storage remain under the control of the Department of the Army and no accounting for disclosure is required under the Privacy Act. (G) 5 U.S.C. 552a(b)(7) ·To another agency or instrumentality of any governmental jurisdiction within or under the control of the United States for a civil or criminal law enforcement activity, if the activity is authorized by law, and if the head of the agency or instrumentality has made a written request to the Department of the Army or DoD specifying the particular portion desired and the law enforcement activity for which the record is sought. (H) 5 U.S.C. 552a(b)(8) ·To a person pursuant to a showing of compelling circumstances affecting the health or safety of an individual if upon such disclosure, notification is transmitted to the last known address of such individual. (I) 5 U.S.C. 552a(b)(9) ·To either House of Congress, or, to the extent the matter is within its jurisdiction, any committee or subcommittee thereof, or any joint committee of Congress or subcommittee of any such joint committee. Requests from a Congressional member acting on behalf of a constituent are not included in this exception, but may

be covered by a routine use exception to the Privacy Act (See applicable Army system of records notice). (J) 5 U.S.C. 552a(b)(10) ·To the Comptroller General or authorized representatives, in the course of the performance of the duties of the Government Accountability Office. (K) 5 U.S.C. 552a(b)(11) ·Pursuant to the order of a court of competent jurisdiction. The order must be signed by a judge. (L) 5 U.S.C. 552a(b)(12)

Privacy Act notification, access, and amendment rights relative to the records maintained in this system are available only to individuals who are the subject of records in this system. The individuals who are the subjects of the records stored in this system are the State or local officials who are currently commissioned, have applied for a commission, and/or were commissioned or rejected in the past. Although records in the system may contain personally identifiable information related to other individuals, only the specified commissioned or commission-seeking individuals are considered subjects of records in this system. F. Categories of Records in the System The records in this system will include: Full name, aliases, date of birth, home address, work address, telephone number, work or personal email address, photograph, educational history, job title, agency, division, area of expertise, employment history, supervisor's name, signature, and the outcome of the background investigation of individuals who apply for a commission. Should a commissioned individual with pocket credentials lose their credentials, he or she will typically file a police report and provide a copy of the report to FDA where it is kept in the individual's commissioning file. In addition, the records in the system will describe the nature of the authority granted to a commissioned individual, the relevant regulatory program area, the date the commission was issued, and date of expiration. G. Authority for Maintenance of the System The authorities for maintaining this system are: Section 702(a) of the FD&C Act, 44 U.S.C. 3101 , and 5 U.S.C. 301 . H. Purpose(s) of the System Relevant Agency personnel will use records from this system on a need-to-know basis to: Centrally gather data enabling FDA to determine the suitability, eligibility, and qualifications of State and local officials to whom FDA might offer commissions; enable FDA to securely commission and credential State and local officials who are particularly qualified to assist FDA in a special manner for which FDA credentials are required; ensure the safety and security of FDA facilities, systems, information, and of facility occupants and users; provide appropriate access to FDA information systems, networks, and resources; enhance FDA's ability to ensure the safety of FDA-regulated products through a secure commissioning process; and centrally gather data on commissioned officials, thereby enabling FDA to efficiently maintain the commissioning program and to support activities, such as quickly ascertaining which officials are particularly qualified to carry out official responsibilities and providing this information as necessary to our State and local counterparts. I. Routine Uses of Records Maintained in the System, Including Categories of Users and the Purposes of Such Uses These routine uses specify circumstances, in addition to those provided by the Privacy Act at 5 U.S.C. 552a(b)

As discussed in more detail later in the regulatory text, all requirements that are scored as NOT MET are identified in a Plan of Action and Milestones (POA&M) to meet the CMMC requirement. Organizations Seeking Assessment (OSAs) satisfy the CMMC requirements needed for contract award by successfully meeting all 110 security requirements of NIST SP 800-171 R2 or by receiving a Conditional CMMC Status when achieving the minimum passing score of 80 percent and only including permissible NOT MET requirements as described in §.170.21 on the POA&M. All requirements that were scored ·NOT MET· and placed on the POA&M must be remedied within 180 days of receiving their Conditional CMMC Status. Proper implementation of these requirements must be verified by a second assessment, called a POA&M closeout assessment. If the POA&M closeout assessment finds that all requirements have been met, then the OSA will achieve a CMMC Status of Final Level 2 (Self) or Final Level 2 (C3PAO) as applicable. However, if the POA&M closeout assessment does not validate all requirements have been met by the end of the 180 days, then the CMMC Status of Conditional Level 2 (Self) or Conditional Level 2 (C3PAO) will expire and at this point, standard contractual remedies will apply for any current contract. DoD has created a series of guidance documents to assist organizations in better understanding the CMMC Program and the assessment process and scope for each CMMC level. These guidance documents are available on the DoD CMMC website at <https://dodcio.defense.gov/·CMMC/·Documentation/·> and on the DoD Open Government website at <https://open.defense.gov/·Regulatory-Program/·Guidance-Documents/·> . The CMMC Program has also been incorporated in the Department's 2024 Defense Industrial Base Cybersecurity Strategy. [10] The strategy requires the Department to coordinate and collaborate across components to identify and close gaps (printed page 83094) in protecting DoD networks, supply chains, and other critical resources. Other prongs of the Department's cybersecurity strategy are described in the Department's

National Industrial Security Program Operating Manual (NISPOM) which address implementation of the Security Executive Agent Directive (SEAD) 3 [11] procedures for the protection and reproduction of classified information; controlled unclassified information (CUI); National Interest Determination (NID) requirements for cleared contractors operating under a Special Security Agreement for Foreign Ownership, Control, or Influence; and eligibility determinations for personnel security clearance processes and requirements. [12] Overview of Revised CMMC Program Current Requirements for Defense Contractors and Subcontractors Currently, Federal contracts (including defense contracts) involving the transfer of FCI to a non-Government organization follow the requirements specified in 48 CFR 52.204-21 (Federal Acquisition Regulation (FAR) clause 52.204-21),

PE.L2-3.10.6 · Alternative Work Sites CMMC Assessment Guide · Level 2 | Version 2.13 191 include physical protections, such as locked file drawers, as well as electronic protections such as encryption, audit logging, and proper access controls. Example Many of your company's project managers work remotely as they often travel to sponsor locations or even work from home. Because the projects on which they work require access to CUI, you must ensure the same level of protection is afforded as when they work in the office. You ensure that each laptop is deployed with patch management and anti-virus software protection [b]. Because data may be stored on the local hard drive, you have enabled full-disk encryption on their laptops [b]. When a remote staff member needs access to the internal network you require VPN connectivity that also disconnects the laptop from the remote network (i.e., prevents split tunneling) [b]. The VPN requires multifactor authentication to verify remote users are who they claim to be [b]. Potential Assessment Considerations · Do all alternate sites where CUI data is stored or processed meet the same physical security requirements as the main site [b]? · Does the alternate processing site provide information security measures equivalent to those of the primary site [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.10.6

(6) There are no approved filing procedures for the disclosure of accounting records; however, system managers must be able to retrieve upon request. With this said, keep disclosure accountings for 5 years after the disclosure, or for the life of the record, whichever is longer. (7) When an individual requests such an accounting, the system manager or designee will respond within 20 working days. §-505.8 Training requirements. (a) Training . (1) The Privacy Act requires all heads of Army Staff agencies, field operating agencies, direct reporting units, Major Commands, subordinate commands, and installations to establish rules of conduct for all personnel involved in the design, development, operation, and maintenance of any Privacy Act system of records and to train the appropriate personnel with respect to the privacy rules including the penalties for non-compliance (See 5 U.S.C. 552a(e)(9)). (2) To meet the training requirements, three general levels of training must be established. They are: (i) Orientation. Training that provides basic understanding of this part as it applies to the individual's job performance. This training will be provided to personnel, as appropriate, and should be a prerequisite to all other levels of training; (ii) Specialized training. Training that provides information as to the application of specific provisions of this part to specialized areas of job performance. Personnel of particular concern include, but are not limited to, personnel specialists, finance officers, DOD personnel who may be expected to deal with the news media or the public, special investigators, paperwork managers, individuals working with medical and security records, records managers, computer systems development personnel, computer systems operations personnel, statisticians dealing with personal data and program evaluations, contractors and anyone responsible for implementing or carrying out functions under this part. Specialized training should be provided on a periodic basis; and (iii) Managerial training. Training designed to identify for responsible managers (such as senior system managers, Denial Authorities, and functional managers described in this section) issues that they should consider when making management decisions affected by the Privacy Act Program. (b) Training tools. Helpful resources include: (1) Privacy Act training slides for Major Commands and Privacy Act Officers: Contact the DA FOIA/P Office, or slides can be accessed at the Web site <https://www.rmda.belvoir.army.mil/rmdaxml/rmda/FPHomePage.asp> . (2) The 'DOJ Freedom of Information Act Guide and Privacy Act Overview': The U.S. Department of Justice, Executive Office for United States Attorneys, Office of Legal Education, 600 E. Street, NW., Room 7600, Washington, DC 20530, or training programs can be accessed at the Web site <http://www.usdoj.gov/usao/eousa/ole.html> . §-505.9 Reporting requirements.

d their connected resource consumers are the primary concerns of an RM. 3. Resource consumers (RCs)

are client applications that accept user requests for resources and forward those requests to an RM. Ideally, an RP should only have to communicate with one RM because the dissemination of shared resources is achieved by the RM. Only one connection between an RM and an RC is expected as well because the discovery of resource locations should be done by an RM, as illustrated in Fig. 11.

From the NIST SP 800-172 Rev 3 Final Public Draft: Purpose and Applicability This publication provides federal agencies with a set of recommended enhanced security requirements 8 The term requirements is used in this guideline to describe the stakeholder protection needs of a particular system or organization. Stakeholder protection needs and corresponding security requirements may be derived from many sources (e.g., laws, Executive Orders, directives, regulations, policies, standards, mission and business needs, or risk assessments). for protecting the confidentiality, integrity, and availability of CUI when such information is resident in nonfederal systems and organizations and where there are no specific safeguarding requirements prescribed by the authorizing law, regulation, or government-wide policy for the CUI category I

CMMC Level 3 scoring does not utilize varying values like the scoring for CMMC Level 2. All CMMC Level 3 security requirements use a value of 1 point for each security requirement. As a result, the maximum score achievable for a CMMC Level 3 is equivalent to the total number of CMMC Level 3 security requirements. The maximum score is reduced by one (1) point for each security requirement NOT MET. The CMMC Level 3 scoring methodology reflects the fact that all CMMC Level 2 security requirements must already be MET (for the Level 3 CMMC Assessment Scope). A maximum CMMC Level 2 assessment score is required to be eligible for conduct of a CMMC Level 3 Certification Assessment. The CMMC Level 3 assessment score is equal to the number of CMMC Level 3 security requirements that are assessed as MET. Appendix A to Part 170-Guidance. Guidance Documents include: (a) CMMC Model Overview available at <https://DoDcio.defense.gov/CMMC/> . (b) CMMC Assessment Guide-Level 1 available at <https://DoDcio.defense.gov/CMMC/> . (c) CMMC Assessment Guide-Level 2 available at <https://DoDcio.defense.gov/CMMC/> . (d) CMMC Assessment Guide-Level 3 available at <https://DoDcio.defense.gov/CMMC/> . (e) CMMC Scoping Guide-Level 1 available at <https://DoDcio.defense.gov/CMMC/> . (f) CMMC Scoping Guide-Level 2 available at <https://DoDcio.defense.gov/CMMC/> . (g) CMMC Scoping Guide-Level 3 available at <https://DoDcio.defense.gov/CMMC/> . (h) CMMC Hashing Guide available at <https://DoDcio.defense.gov/CMMC/> . See these guidance documents in docket number DoD-2023-OS-0096 for specific details and to provide comments on the guidance. Patricia L. Toppings, OSD Federal Register Liaison Officer, Department of Defense. Footnotes 1. <https://www.federalregister.gov/citation/75-FR-68675> (November 4, 2010). Back to Citation 2. <https://www.federalregister.gov/citation/75-FR-707> (December 29, 2009). Back to Citation 3. <https://www.govinfo.gov/link/uscode/42/2011> , et seq. Back to Citation 4. <https://www.federalregister.gov/documents/2020/09/29/2020-21123/defense-federal-acquisition-regulation-supplement-assessing-contractor-implementation-of> . Back to Citation 5. <https://www.acquisition.gov/far/52.204-21> . Back to Citation 6. <https://www.acquisition.gov/dfars/252.204-7012-safeguarding-covered-defense-information-and-cyber-incident-reporting> . Back to Citation 7. Required since November 2016, NIST SP 800-171 security requirement 3.12.4 states organizations must develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems. Back to Citation 8. <https://www.sprs.csd.disa.mil/> under OMB control number 0750-0004. Back to Citation 9. The POA requirement described under DFARS clause 252.204-7012 is different from a Plan of Action and Milestones (POA&M) requirement in CMMC as POAs do not require milestones. Back to Citation 10.

Web services span many applications and domains. Consequently, any vulnerability in one service can be exploited to affect more than one service. In Web Services architecture it is a challenge to investigate the nature and source of an attack. We propose a framework referred to - [1] A. Vorobiev and H. Jun, "Security Attack Ontology for Web Services," in Semantics, Knowledge and Grid, 2006. SKG '06. Second International Conference on , 2006, pp. 4242. - [2] Y. Demchenko, L. Gommans, C. de Laat, and B. Oudenaarde, "Web services and grid security vulnerabilities and threats analysis and model," in Grid Computing, 2005. The 6th IEEE/ACM International Workshop on , 2005, p. 6 pp. - [3] A. Singhal, T. Winograd, and K. Scarforne, NIST Special Publication 800-95, "Guide to Secure Web Services" , August 2007, <http://csrc.nist.gov/publications/nistpubs/80095/SP800-95.pdf>. - [4] R. Khalaf, N. Mukhi, and S. Weerawarana, "Service-Oriented Composition in BPEL4WS," in Twelfth

International World Wide Web Conference , Budapest, Hungary, 2003. - [5] S. M. S. Cruz, M. L. M. Campos, P. F. Pires, and L. M. Campos, "Monitoring e-business Web services usage through a log based architecture," in Web Services, 2004. Proceedings. IEEE International Conference on , 2004, pp. 61-69. - [6] A. Herzberg and I. Yoffe, "The Delivery and Evidences Layer," Cryptology ePrint Archive Report 2007/139, 2007. - [7] S. Kremer, O. Markowitch, and J. Zhou, "An Intensive Survey of Non-repudiation protocols," Computer Communications, vol. 25, pp. 1606-1621, 2002. - [8] P. Robinson, N. Cook, and S. Shrivastava, "Implementing fair non-repudiable interactions with Web services," in EDOC Enterprise Computing Conference, 2005 Ninth IEEE International , 2005, pp. 195-206. - [9] S. T. King and P. M. Chen. 'Backtracking Intrusions,' in Proceedings of the 2003 Symposium on Operating Systems Principles (SOSP) , pages 223-236, October 2003. - [10] M. Gunestas, D.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Health and Human Services Food and Drug Administration [Docket No. FDA-2011-D-0730] AGENCY: Food and Drug Administration, HHS. ACTION: Notice. SUMMARY: The Food and Drug Administration (FDA) is announcing the availability of a draft guidance entitled ·Class II Special Controls Guidance Document: In Vitro Diagnostic Devices for Yersinia Species Detection· This draft guidance document describes a means by which in vitro diagnostic devices for Yersinia species (spp.) detection may comply with the requirement of special controls for class II devices. This draft guidance is not final nor is it in effect at this time. DATES: Although you can comment on any guidance at any time (see 21 CFR 10.115 (g)(5)), to ensure that the Agency considers your comment on this draft guidance before it begins work on the final version of the guidance, submit either electronic or written comments on the draft guidance by February 6, 2012. ADDRESSES: Submit written requests for single copies of the draft guidance document entitled ·Class II Special Controls Guidance Document: In Vitro Diagnostic Devices for Yersinia spp. Detection· to the Division of Small Manufacturers, International, and Consumer Assistance, Center for Devices and Radiological Health, Food and Drug Administration, 10903 New Hampshire Ave. Bldg. 66, rm. 4613, Silver Spring, MD 20993-0002. Send one self-addressed adhesive label to assist that office in processing your request, or fax your request to (301) 847-8149. See the SUPPLEMENTARY INFORMATION section for information on electronic access to the guidance. Submit electronic comments on the draft guidance to <http://www.regulations.gov> . Submit written comments to the Division of Dockets Management (HFA-305), Food and Drug Administration, 5630 Fishers Lane rm. 1061, Rockville, MD 20852. Identify comments with the docket number found in brackets in the heading of this document. FOR FURTHER INFORMATION CONTACT: Beena Puri, Center for Devices and Radiological Health, Food and Drug Administration, 10903 New Hampshire Ave. Bldg. 66, Rm. 5553, Silver Spring, MD 20993-0002, (301) 796-6202. SUPPLEMENTARY INFORMATION: I. Background Elsewhere in this issue of the Federal Register , FDA is publishing a proposed rule to classify in vitro diagnostic devices for Yersinia spp. detection into class II (special controls). This draft special controls guidance document was developed to support the proposed classification of in vitro diagnostic devices for Yersinia

CMVP Approved Authentication Mechanisms: ## CMVP Approved Authentication Mechanisms: NIST Special Publication (SP) 800-140E replaces the approved authentication mechanism requirements of ISO/IEC 19790 Annex E and ISO/IEC 24759 paragraph 6.17. As a validation authority, the Cryptographic Module Validation Program (CMVP) may supersede ISO/IEC 19790 Annex E and ISO/IEC 24759 paragraph 6.17 in its entirety with its own list of approved authentication mechanisms.

OSCs may submit appeals to C3PAOs as addressed in §.170.9(b)(20). The Accreditation Body provides all plans related to potential sources of revenue, to include but not limited to: fees, licensing, processes, membership, and/or partnerships to the Government's CMMC PMOs addressed in §.170.8(b)(13). C3PAOs maintain records for a period of six years of monitoring, education, training, technical knowledge, skills, experience, and authorization of each member of its personnel involved in inspection activities; contractual agreements with OSCs and organizations for whom consulting services were provided; and working papers generated from Level 2 Certification Assessments as addressed in §.170.9(b)(10). CAICOs maintain records for a period of six (6) years of all procedures, processes, and actions related to fulfillment of the requirements set forth in §.170.10(b)(9). OSCs must retain artifacts used as evidence for the assessment for the duration of the validity period of the certificate of assessment, and at minimum, for six (6) years from the

date of certification assessment as addressed in § 170.17(c)(4). The public respondent burden and labor cost for the information collection reporting and recordkeeping requirements under the CMMC Level 2 Certification Assessment are as follows: Note: This respondent burden and labor cost does not include the requirement for the OSC to upload the affirmation in SPRS (addressed in Title 48 acquisition rule and ICR). (printed page 89113) (printed page 89114) (printed page 89115) CMMC Level 3 Certification Assessment Collection The Level 3 Certification Assessment information collection reporting and recordkeeping requirements are included in this part with the exception of the requirement for the OSC to upload the affirmation in SPRS that will be included in the Title 48 acquisition rule and an update to the DFARS collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Additionally, the information collection reporting requirements for the CMMC instantiation of eMASS are included in a separate ICR for this part and cover only those requirements pertaining to the CMMC process. The information collection reporting requirements for eMASS include: DCMA DIBCAC submits pre-assessment and planning material, final assessment reports, and appropriate CMMC certificates of assessment into the CMMC instantiation of eMASS as addressed in § 170.7 of this part. The DCMA DIBCAC uploads assessment data compliant with the CMMC assessment data standard into the CMMC instantiation of eMASS as addressed in § 170.7(a)(5) of this part. DCMA DIBCAC posts POA&M closeout assessment compliance results into the CMMC instantiation of eMASS in accordance with § 170.18(a)(1)(ii)(B) of this part. DCMA DIBCAC uploads artifacts (list of artifacts, hash of artifacts, and hashing algorithm used) into the CMMC instantiation of eMASS as addressed in § 170.7(a)(5) of this part.

(D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (34) System identifier and name. A0025-2 PMG (DFBA) DoD, Defense Biometrics Identification Records System. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Exempt materials from other sources listed above may become part of the case records in this system of records. To the extent that copies of exempt records from other sources listed above are entered into these case records, the Department of the Army hereby claims the same exemptions, (j)(2) and (k)(2), for the records as claimed by the source systems, specifically to the extent that copies of exempt records may become part of these records from JUSTICE/FBI-019 Terrorist Screening Records System, the Department of the Army hereby claims the same exemptions for the records as claimed at their source (JUSTICE/FBI-019, Terrorist Screening Records System). (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(j)(2) and (k) (2) from subsections 5 U.S.C. 552a(c)(3) , (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (e)(4)(H), (e)(4)(I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(2) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (c)(4) because an exemption is being claimed for subsection (d), making this subsection not applicable. (C) From subsection (d) because access to such records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement.

New suppliers are subject to a cybersecurity assessment by the Mayo Clinic's OIS. The OIS interviews the supplier's information security staff and reviews internal policy, cybersecurity attestations, and process documents to determine whether the vendor is conformant to the cybersecurity requirements established for the relevant supply category group. Particular emphasis is placed on the supplier's handling of regulated data, third-party network access, and secure software development practices. Moreover, complex medical devices invoke specialized requirements, such as detailed design diagrams, evidence of rigorous vulnerability assessments, and supporting

documentation.

The revisions and addition read as follows: 52.204-16 Commercial and Government Entity Code Reporting. * * * * * (printed page 40064) Commercial and Government Entity Code Reporting (Aug 2020) * * * * * (b) The Offeror shall provide its CAGE code with its offer with its name and location address or otherwise include it prominently in its proposal. The CAGE code must be for that name and location address. Insert the word 'CAGE' before the number. The CAGE code is required prior to award. * * * * * (e) When a CAGE code is required for the immediate owner and/or the highest-level owner by Federal Acquisition Regulation (FAR) 52.204-17 or 52.212-3(p), the Offeror shall obtain the respective CAGE code from that entity to supply the CAGE code to the Government. * * * * * (g) If the solicitation includes FAR clause 52.204-2, Security Requirements, a subcontractor requiring access to classified information under a contract shall be identified with a CAGE code on the DD Form 254. The Contractor shall require a subcontractor requiring access to classified information to provide its CAGE code with its name and location address or otherwise include it prominently in the proposal. Each location of subcontractor performance listed on the DD Form 254 is required to reflect a corresponding unique CAGE code for each listed location unless the work is being performed at a Government facility, in which case the agency location code shall be used. The CAGE code must be for that name and location address. Insert the word 'CAGE' before the number. The CAGE code is required prior to award. (End of provision) 8. Amend section 52.204-17 by revising the title and the date of the provision and removing from paragraph (a)(1) 'entity; or' and adding 'entity by unique location; or' in its place. The revision reads as follows: 52.204-17 Ownership or Control of Offeror. * * * * * Ownership or Control of Offeror (Aug 2020) * * * * * 9. Amend section 52.204-18 by: a. Revising the date of the clause; b. Removing from paragraph (a)(1) 'entity; or' and adding 'entity by unique location; or' in its place; c. Revising the first sentence of paragraph (b); and d. Adding paragraph (f). The revisions and addition read as follows: 52.204-18 Commercial and Government Entity Code Maintenance. * * * * * Commercial and Government Entity Code Maintenance (Aug 2020) * * * * * (b) Contractors shall ensure that the CAGE code is maintained throughout the life of the contract for each location of contract, including subcontract, performance. * * * * * (f) If the contract includes Federal Acquisition Regulation clause 52.204-2, Security Requirements, the contractor shall ensure that subcontractors maintain their CAGE code(s) throughout the life of the contract. (End of clause) 10. Amend section 52.204-20 by: a. Revising the date of the provision; and b. Removing from paragraph (a)(1) 'entity; or' and adding 'entity by unique location; or' in its place. The revision reads as follows: 52.204-20 Predecessor of Offeror. * * * * * Predecessor of Offeror (Aug 2020) * * * * * PART 53-FORMS 11.

) of unclassified information that requires safeguarding or dissemination controls. NARA's CUI Registry identifies the organizational index grouping and related categories of information and specifies how the information should be marked and disseminated, among other actions that must be taken. NARA's rule codified uniform policies and procedures for marking, safeguarding, disseminating, decontrolling, and disposing of CUI for Federal executive branch agencies at 32 CFR part 2002 . These policies also affect contractors that are expected to collect, develop, receive, transmit, use, handle, or store CUI during contract performance. To apply the policies to contractors, the CUI Program must be incorporated into the acquisition process, specifically, when agencies define their requirements, issue solicitations, and award contracts. In order to do so, Government and contractor roles and responsibilities for safeguarding, using, marking, disseminating, and decontrolling CUI residing on both Federal and non-Federal information systems must be identified. DoD has implemented the requirements of the CUI Program within the clause at Defense Federal Acquisition Regulation Supplement (DFARS) 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting. DoD has also proposed amending the DFARS to incorporate contractual requirements associated with the Cybersecurity Maturity Model Certification program (CMMC) in order to verify contractor implementation of security controls through a proposed rule published in the Federal Register on August 15, 2024, at 89 FR 66327 . Separately, the CMMC program was established in Title 32 of the Code of Federal Regulations through a final rule published in the (printed page 4279) Federal Register on October 15, 2024, at 89 FR 83092 . DoD, GSA, and NASA are proposing to revise the FAR to implement NARA's final rule on the Federal CUI Program as it relates to performance under Federal contracts. The Privacy Act requirements at FAR part 24 are not changed by this rulemaking. DoD, GSA, and NASA propose to create a common mechanism, the Standard Form XXX, Controlled Unclassified Information (CUI) Requirements, to enable a uniform process for communicating the information contractors must manage and safeguard as well as

identify where a CUI incident must be reported and when there are CUI incident reporting requirements that differ from or are in addition to those in the clause at FAR 52.204-XX(g). Currently laws, Federal regulations, and Government-wide policies already mandate these protections, but there is not a standard way these requirements are identified and shared with contractors. This proposed rule is just one element of a larger strategy to improve the Government's efforts to identify, deter, protect against, detect, and respond to increasingly sophisticated criminals and adversaries targeting Federal information and information systems. II. Discussion and Analysis

From the NIST SP 800-172 Rev 3 Final Public Draft: Every system and system component has a point of origin and may be changed throughout its existence. Provenance is the chronology of the origin, development, ownership, location, and changes to a system or system component and associated data. It may also include personnel and processes used to interact with or make modifications to the system, component, or associated data. Organizations have methods to document, monitor, and maintain valid provenance baselines for systems, system components, and related data. These actions help track, assess, and document any changes to the provenance, including changes in supply chain elements or configuration, and help ensure non-repudiation of provenance information and the provenance change records. This requirement does not enhance a

Appropriate management practices are essential to operating and maintaining a secure mail server. Security practices entail the identification of an organization's information system assets and the development, documentation, and implementation of policies, standards, procedures, and guidelines that help to ensure the confidentiality, integrity, and availability of information system resources. Organizations often want to protect the confidentiality and integrity of some of their email messages, such as preventing the exposure of personally identifiable information in an email attachment. Email messages can be protected by using cryptography in various ways, such as the following: - GLYPH; - Sign an email message to ensure its integrity and confirm the identity of its sender. - GLYPH; Encrypt the body of an email message to ensure its confidentiality. - GLYPH; Encrypt the communications between mail servers to protect the confidentiality of both the message body and message header.

Based on the discussion in paragraphs IV.B.2.i. through IV.B.2.x. below, the total annual estimated cost for 28 contractors, as applicable, awarded a contract to develop, implement, operate, or maintain an existing or custom-build, non-cloud FIS on behalf of the Government, to comply with NIST guidelines in year one is approximately \$19.6 million, and approximately \$12 million each subsequent year for annual maintenance to remain compliant with existing NIST guidelines. The cost for complying with NIST guidelines accounts for the time it takes contractors to closely read through the documents, analyze the requirements against the current state and identify any necessary changes, and implement and document the change, as needed. i. NIST SP 800-53. The effort and resources a contractor will expend to comply with NIST SP 800-53 will also vary depending on whether the affected FIS is an existing system or a system that will be custom built to Government specifications. Existing systems already implement some of the guidelines required by the clause or their implementation has been accepted by the Government, while custom-built systems have no pre-existing controls in place and will require a greater amount of effort and resources to be compliant with the clause. The Government estimates that of the 28 contractors annually awarded a contract to develop, implement, operate, or maintain a non-cloud FIS, approximately six contractors (20 percent) are awarded a contract involving a custom-build system, while the remaining 22 contractors (80 percent) are awarded a contract involving an existing system. Contractors awarded a contract involving an existing non-cloud FIS are anticipated to expend between 2,300 and 6,500 hours and \$218,000 and \$683,000 in labor and materials in year one to implement, and between \$127,000 and \$478,000 each following year to maintain compliance with NIST SP 800-53. The cost and effort to implement and maintain compliance will vary by contractor depending on various factors, including: the complexity of the information system; the availability of employees with the requisite knowledge and skills to implement the necessary controls; the need to install hardware or software, and the chosen solution, as well as the number of users impacted, the types of devices used, and the complexity of the contractor's network. Contractors awarded a contract involving a custom build non-cloud FIS will expend between 3,000 and 7,300 hours and between \$308,000 and \$976,000 in labor and materials in year one to implement, and between \$126,000 and \$478,000 each following year to maintain compliance with NIST SP 800-53. The cost and effort to maintain compliance will vary by contractor based on the factors discussed above. ii. NIST SP 800-213.

- The SP 800-53, Revision 5 low baseline is a defined map of controls to secure a system defined as a low-impact information system. The loss of confidentiality, integrity, or availability could be expected to have a limited adverse effect on organizational operations, organizational assets, or individuals. - The SP 800-53, Revision 5 moderate baseline is a defined map of controls to secure a system defined as a moderate-impact information system. The loss of confidentiality, integrity, or availability could be expected to have a serious adverse effect on organizational operations, organizational assets, or individuals. - The SP 800-53, Revision 5 high baseline is a defined map of controls to secure a system defined as a high-impact information system. The loss of confidentiality, integrity, or availability could be expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. offer a convenient, Apple-supported mechanism for applying security settings to a macOS environment. Additionally, they can be cryptographically signed to ensure integrity and authenticity. These factors make configuration profiles the preferred vehicle for configuration delivery. However, mobileconfig files cannot modify all macOS settings, so a configuration script is needed for those settings that are not supported. See the developer documentation page for an example configuration profile and brief descriptions of its properties. This example is for Tenable, Inc. They automated the conversion of mSCP YAML rules into their . audit format using Python and YAML libraries. Programmatically approaching this conversion allows for faster future releases and greater consistency, and it also maintains the integrity of the source content. Because the YAML content is all command-driven, it is converted to Tenable's CMD_EXEC check type for use with the Unix plugin.

An official charged with the responsibility to rule on administrative appeals of initial denials of requests for notification, access, or amendment of records. Additionally, the Office of Personnel Management is the review authority for civilian official personnel folders or records contained in any other OMP record. (bb) Routine Use. Disclosure of a record outside DOD without the consent of the subject individual for a use that is compatible with the purpose for which the information was collected and maintained by DA. A routine use must be included in the notice for the Privacy Act system of records published in the Federal Register . (cc) Statistical record. A record in a system of records maintained for statistical research or reporting purposes and not used in whole or in part in making determinations about specific individuals. (dd) System Manager. An official who has overall responsibility for policies and procedures for operating and safeguarding a Privacy Act system of records. (ee) Third-party cookies. Cookies placed on a user's hard drive by Internet advertising networks. The most common third-party cookies are placed by the various companies that serve the banner ads that appear across many Web sites. (ff) Working Days. Days excluding Saturday, Sunday, and legal holidays. [FR Doc. 06-6799 Filed 8-9-06; 8:45 am] BILLING CODE 3710-08-P

Instead, the Department proposed to require that each covered entity assess its own security needs and risks and devise, implement, and maintain appropriate security to address its business requirements. The Department believed that this approach would leave a significant amount of flexibility for covered entities and balance the needs of securing health data against risk with the economic cost of doing so. [79] 2. 2003 Final Rule The Department issued the final Security Rule [80] on February 20, 2003 (-2003 Final Rule-). In accordance with the Administrative Simplification provisions of HIPAA, the 2003 Final Rule adopted standards for the security of ePHI to be implemented by covered entities. The Department reiterated the purposes and guiding principles it articulated in the 1998 Proposed Rule and repeated that the protection of the privacy of information depends in large part on the existence of security measures to protect that information. [81] The Department noted that there were still no standard measures in the health care industry that address all aspects of the security of ePHI while it is being stored or during the exchange of that information between entities. [82] The Department explained that the use of the security standards would improve the Medicare and Medicaid programs, other Federal health programs and private health programs, and the effectiveness and efficiency of the health care industry in general by establishing a level of protection for ePHI. [83] Provisions of the 2003 Final Rule did not mirror the 1998 Proposed Rule; rather, the Department finalized only certain changes. The Department noted, for example, that to maintain consistency with the use of terms as they appear in the statute and other previously released HIPAA Rules (i.e., the HIPAA Privacy and Transactions Rules), it was changing some terminology from the 1998 Proposed Rule, replacing the terms ·requirement· with ·standard· and ·implementation feature· with ·implementation specification·. [84] According to the Department, the comments received in response to the

1998 Proposed Rule overwhelmingly validated its basic assumptions that the covered entities were so varied in terms of installed technology, size, resources, and relative risk, that it would be impossible to dictate a specific solution or set of solutions that would be usable by all covered entities. [85] Similarly, we received numerous comments expressing the view that the security standards should not be overly prescriptive because the speed with which technology is evolving could make specific requirements obsolete and might in fact deter technological progress. Accordingly, the Department framed the standards in the 2003 Final Rule in terms that were as generic as possible and that could generally be met through a variety of approaches or technologies. [86] The standards, we (printed page 905) explained, do not allow organizations to make their own rules, only their own technology choices. [87]

what, if any, federal government support is needed to improve authentication/identity management controls, mechanisms, and supporting infrastructures? Do the authentication and/or identity management controls employed by commercial organizations or business sectors, in general, provide adequate assurance? If not, what improvements are needed? What specific controls and mechanisms should be implemented? What role should authentication and identity management controls play in a comprehensive set of cybersecurity measures available to commercial organizations? Are the basic infrastructures that underlie the recommended controls and mechanisms already in place? What, if any, new tools or technologies for authentication or identify management are available or are being developed that may address these needs? How can the expense associated with improved authentication/identity management controls and mechanisms be justified financially? How can the U.S. Government best support improvement of authentication/identity management controls, mechanisms, and supporting infrastructures? Is there a continuing need for limited revelation identity systems, or even anonymous identity processes and credentials? If so, what would be the potential benefits of wide-scale adoption of limited revelation identity systems or anonymous credentialing from a cybersecurity perspective? What would be the drawbacks? How might government procurement activities best promote development of a market for more effective authentication tools for use by government agencies and commercial entities? Could a private marketplace for identity brokers (i.e., organizations that can be trusted to establish identity databases and issue identity credentials adequate for authorizing financial transactions and accessing private sector components of critical infrastructures) fulfill this need effectively? What would be some of the issues or potential impacts of establishing standards and best practices for private sector identity brokers? Should the government establish a program to support the development of technical standards, metrology, test beds, and conformance criteria to take into account user concerns such as how to: (1) Improve interoperability; (2) strengthen authentication methods; (3) improve privacy protection through authentication and security protocols; and (4) improve the usability of identity management systems? What are the privacy issues raised by identity management systems and how should those issues be addressed? Are there particular privacy and civil liberties questions raised by government involvement in identity management system design and/or operations? What other considerations should factor into government's efforts in this area? 5. Global Engagement

Total recordkeeping burden hours: 122,904. This estimate is based on one recordkeeper who spends one hour per month (or 12 hours per year) maintaining the system security plan. 2. Preserve, Protect, and Submit Media and Data. Public reporting burden for this collection of information is estimated to average 2.5 hours per response including the time to prepare and complete the submission. The annual reporting burden is estimated as follows: Respondents: 48. Total annual responses: 48. Total burden hours: 120. This estimate is based on approximately one response per respondent. The annual recordkeeping burden is estimated as follows: Recordkeepers: 580. Total annual records: 580. Total recordkeeping burden hours: 4,350. This estimate is based on one recordkeeper who spends 7.5 hours per year to preserve and protect images of all known affected information systems and all relevant monitoring and packet capture data, assuming 0.5 hours to image, 2 hours to preserve monitoring and packet capture data, and 5 hours to upload images and set up storage space. 3. CUI Incident Reporting. Public reporting burden for this collection of information is estimated to average 5 hours per response including the time to prepare and submit a CUI incident report. The annual reporting burden is estimated as follows: Respondents: 580. Total annual responses: 580. Total burden hours: 2,900. This estimate is based on approximately one response per respondent. 4. Training Records. Public reporting burden for this collection of information is estimated to average 15 minutes (0.25 hour) per response including the time to prepare and submit the evidence of training. The annual reporting burden is estimated as follows: Respondents: 1,430. Total annual responses: 1,430. Total burden hours: 357.5. This estimate is

based on approximately one response per respondent. The annual recordkeeping burden is estimated as follows: Recordkeepers: 53,225. Total annual records: 2,191,400. Total recordkeeping burden hours: 181,886. (printed page 4290) This estimate is based on one recordkeeper who spends 5 minutes (0.083 hours) per record maintaining the employee training certificates. 5. Prepare and Distribute the SF XXX. Public reporting burden for this collection of information is estimated to average 2 hours per response including the time to prepare and distribute the SF XXX. The annual reporting burden is estimated as follows: Respondents: 22,680. Total annual responses: 517,392. Total burden hours: 1,034,784. B. Request for Comments Regarding Paperwork Burden Submit comments on this collection of information no later than March 17, 2025 through <https://www.regulations.gov>

(5) Add appropriate Privacy and Security Notices at major Web site entry points. Refer to AR 25-1, para 6-4n for requirements for posting Privacy and Security Notices on public Web sites. Procedures related to the establishing, operating, and maintaining of unclassified DA Web sites can be accessed at http://www.defenselink.mil/webmasters/policy/DOD_web_policy. (6) Ensure public Web sites comply with policies regarding restrictions on persistent and third party cookies. The Army prohibits both persistent and third part cookies. (see AR 25-1, para 6-4n) (7) A Privacy Advisory is required on Web sites which host information systems soliciting personally identifying information, even when not maintained in a Privacy Act system of records. The Privacy Advisory informs the individual why the information is solicited and how it will be used. Post the Privacy Advisory to the Web site page where the information is being solicited, or to a well marked hyperlink stating Privacy Advisory-Please refer to the Privacy and Security Notice that describes why this information is collected and how it will be used. (d) Protecting records containing personal identifiers such as names and Social Security Numbers. (1) Only those records covered by a Privacy Act system of records notice may be arranged to permit retrieval by a personal identifier (e.g., an individual's name or Social Security Number). AR 25-400-2, paragraph 6-2 requires all records covered by a Privacy Act system of records notice to include the system of record identification number on the record label to serve as a reminder that the information contained within must be safeguarded. (2) Use a coversheet or DA Label 87 (For Official Use Only) for individual records not contained in properly labeled file folders or cabinets. (3) When developing a coversheet, the following is an example of a statement that you may use: The information contained within is FOR OFFICIAL USE ONLY (FOUO) and protected by the Privacy Act of 1974. (e) Notification of Individuals when personal information is lost, stolen, or compromised. (1) Whenever an Army organization becomes aware the protected personal information pertaining to a Service member, civilian employee (appropriated or non-appropriated fund), military retiree, family member, or another individual affiliated with Army organization (e.g., volunteer) has been lost, stolen, or compromised, the organization shall inform the affected individuals as soon as possible, but not later than ten days after the loss or compromise of protected personal information is discovered. (2) At a minimum, the organization shall advise individuals of what specific data was involved; the circumstances surrounding the loss, theft, or compromise; and what protective actions the individual can take.

https://media.defense.gov/2024/Mar/28/2003424523/-1/-/1/1/DOD_DOB_CS_STRATEGY_DSD_SIGNED_20240325.PDF . Back to Citation 11. www.govinfo.gov/content/pkg/FR-2020-12-21/pdf/2020-27698.pdf). Back to Citation 12. www.dcsa.mil/Industrial-Security/National-Industrial-Security-Program-Oversight/32-CFR-Part-117-NISPOM-Rule/ . Back to Citation 13. www.acquisition.gov/far/52.204-21 . Back to Citation 14. www.acquisition.gov/dfars/252.204-7012-safeguarding-covered-defense-information-and-cyber-incident-reporting . Back to Citation 15. Required since November 2016, NIST SP 800-171 R2 security requirement 3.12.4 states organizations must develop, document, and periodically update system security plans that describe system boundaries, system environments of operation, how security requirements are implemented, and the relationships with or connections to other systems. Back to Citation 16. www.spr.scd.disa.mil/ under OMB control number 0750-0004. Back to Citation 17. The plan of action requirement described under DFARS clause 252.204-7020 is different from a Plan of Action and Milestones (POA&M) requirement in CMMC as plans of action do not require milestones. Back to Citation 18. www.federalregister.gov/documents/2020/09/29/2020-21123/defense-federal-acquisition-regulation-supplement-assessing-contractor-implementation-of . Back to Citation 19. www.acq.osd.mil/asda/dpc/cp/cyber/docs/safeguarding/NIST-SP-800-171-Assessment-Methodology-Version-1.2.1-6.24.2020.pdf . Back to Citation 20. www.iso.org/standard/67198.html . Back to Citation 21. www.iso.org/standard/52993.html . Back to Citation 22. This system is

accessible only to authorized users. Back to Citation 23. DoD Issuances (www.esd.whs.mil/DD/DoD-Issuances). Back to Citation 24. Based on information from the Council of Economic Advisors report: The Cost of Malicious Cyber Activity to the U.S. Economy, 2018. Back to Citation 25. Based on information from the Center for Strategic and International Studies report on the Economic Impact of Cybercrime; www.csis.org/analysis/economic-impact-cybercrime. Back to Citation 26. Based on information from the Federal Procurement Data System, the average number of unique prime contractors is approximately 212,650 and the number of known unique subcontractors is approximately 8,300. (FPDS from FY18-FY21). Back to Citation 27. www.govinfo.gov/content/pkg/PLAW-116publ92/pdf/PLAW-116publ92.pdf. Back to Citation 28. https://media.defense.gov/2024/Mar/28/2003424523/-1/-1/1/1/1/DOD_DOB_CS_STRATEGY_DSD_SIGNED_20240325.PDF. Back to Citation 29. www.govinfo.gov/content/pkg/FR-2020-12-21/pdf/2020-27698.pdf. Back to Citation 30. www.dcsa.mil/Industrial-Security/National-Industrial-Security-Program-Oversight/32-CFR-Part-117-NISPOM-Rule/. Back to Citation 31. www.gao.gov/assets/gao-22-104746.pdf. Back to Citation 32. www.ic3.gov/Media/News/2021/210310.pdf. Back to Citation 33.

Listeria monocytogenes and *Vibrio parahaemolyticus* were less than the reported total from those pathogens, so we used the reported total instead of the estimated total. Case hospitalization rates for chemical poisoning and for other toxins are not reported in the CDC report, and (because such cases are unusual and characterized by severe acute distress) we assumed that half of such cases would be hospitalized. Finally, we assumed that the total number of illnesses from unknown agents is the same fraction of the estimated total summed over all pathogens, as the reported total summed over all pathogens. The estimated ratio of the total number of illnesses to reported illnesses was computed by dividing the estimated total by the reported total summed of all pathogens. The average estimate of the ratio of total illnesses to reported illnesses from all pathogens, as well as the high and low estimates representing the 95 percent and 5 percent levels are reported in the following table. We estimate a total of 71,928 reported and unreported illnesses from outbreaks monitored by FDA from 2000 to 2003. This total reflects 8,325 illnesses that were reported, and approximately 63,603 that were estimated to be unreported. (printed page 71621) Table 4. Estimated ratio of the total number of illnesses to reported number of illnesses Mean Low (greater than 5% of the range) High (greater than 95% of the range) 8.64 7.89 9.51 5. The Costs of Each Illness We estimate the direct medical costs as well as the indirect costs of illnesses from outbreaks monitored by FDA. The direct medical costs include the costs of any doctor visits and hospitalizations that are required. Indirect costs are from the loss in productivity and quality of life as a result of the symptoms and severity of the illness. We estimate the indirect and direct costs of each illness for mild, moderate, and severe cases. Mild cases are assumed to remain untreated with no direct medical costs. We assume that persons with moderate cases visit a physician and that those with severe cases require hospitalization. The average costs of \$64 for a physician visit was obtained from the online source, Medical Economics (Ref. 4), and hospitalization costs were obtained from the Health Cost and Utility Project's (HCUP) Nationwide Inpatient Sample (Ref. 5) by type of illness. The numbers of days that symptoms persist for each illness and severity were estimated from the FDA-Center for Food Safety and Applied Nutrition (CFSAN) Bad Bug Book (Ref. 6), CDC's National Center for Infectious Diseases, Infectious Disease Information fact sheets (Ref. 7), and from a CFSAN report entitled 'Estimating the Value of Consumers' Loss from Foods Violating the FD&C Act' (Ref. 8). These estimates were assumed to be uniformly distributed with the means reported in table 5 of this document. Table 5. Duration of the illness for mild, moderate, and severe cases Mild Moderate Severe Bacteria Campylobacter 4 8 8 E. coli 0157 3 8 18 Listeria 4 30 37 Salmonella 4 12 16 Shigella

(2) Do not claim an exemption for classified material for individual systems of records. The blanket exemption applies. (See paragraph (c) of § 310.26.) § 310.32 System notices. (a) Contents of the system notices. (1) The following data captions are included in each system notice: (i) Systems identifier. (see paragraph (b) of this section). (ii) System name. (see paragraph (c) of this section). (iii) System location. (see paragraph (d) of this section). (printed page 18777) (iv) Categories of individuals covered by the system. (see paragraph (e) of this section). (v) Categories of records in the system. (see paragraph (f) of this section). (vi) Authority for maintenance of the system. (see paragraph (g) of this section). (vii) Purpose(s). (see paragraph (h) of this section). (viii) Routine uses of records maintained in the system, including categories of users and the purposes of such uses. (see paragraph (i) of this section). (ix) Disclosure to Consumer Reporting Agencies. This element is optional but required when disclosing to consumer

reporting agencies (See paragraph (l) of § 310.22.) (x) Policies and practices for storing, retrieving, accessing, retaining, and disposing of records in the system. (see paragraph (j) of this section). (xi) Systems manager(s) and address. (see paragraph (k) of this section). (xii) Notification procedure. (see paragraph (l) of this section). (xiii) Record access procedures. (see paragraph (m) of this section). (xiv) Contesting records procedures. (see paragraph (n) of this section). (xv) Record source categories. (see paragraph (o) of this section). (xvi) Exemptions claimed for the system. (see paragraph (p) of this section). (2) The captions listed in paragraph (a)(1) of this Section have been mandated by the Office of Federal Register and must be used exactly as presented. (3) A sample system notice is shown in Appendix E of this part. (b) System Identifier. The system identifier must appear on all system notices and is limited to 21 positions, unless an exception is granted by the DPO, including Component code, file number and symbols, punctuation, and spacing. (c) System Name. (1) The name of the system reasonably identifies the general purpose of the system and, if possible, the general categories of individuals involved. (2) Use acronyms only parenthetically following the title or any portion thereof, such as, 'Joint Uniform Military Pay System (JUMPS)'. Do not use acronyms not commonly known unless they are preceded by an explanation. (3) The system name may not exceed 55 character positions, unless an exception is granted by the DPO, including punctuation and spacing. (4) The system name should not be the name of the database or the IT system if the name does not meet the criteria in paragraph (c)(1) of this section. (d) System Location. (1) For systems maintained in a single location provide the exact office name, organizational identity, and address.

Several commenters suggested that defense contractors and subcontractors should be more engaged in the formulation of the rule and better informed in how the rule will be applied. They indicated that guidance is unclear, ad hoc, and inconsistent, and requested an authoritative source of information, such as FAQs, that are kept up to date and provide reliable responses to questions. They also expressed a desire for more transparency in how ambiguities are being resolved in early assessments. Response: In September 2019, the CMMC PMO released the first draft publication of the CMMC Model v 0.4. The CMMC PMO received over 2,000 comments from individuals and industry associations. These comments informed changes included in CMMC Model 1.0 released in January 2020. In addition, DFARS Case 2019-D041 generated over 750 additional public comments that informed changes to the rule text and influenced the transition to CMMC 2.0. The Office of the Under Secretary of Defense for Acquisition and Sustainment (OUSD(A&S)) held over 100 industry listening sessions in 2020 and 2021, engaged with the DIB through briefings and discussions with defense industry trade associations, academia, and government-based organizations with industry members (e.g., National Industrial Security Program Policy Advisory Committee). Many sessions were recorded and shared with the public on the internet in social media, news releases, and the CMMC PMO website (<https://DoDcio.defense.gov/CMMC/>), which was completely updated in 2021 and contains new information, FAQs, and allows the public direct contact with the CMMC PMO. As always, FAQs are to clarify content only, and do not interpret, define, or otherwise change the meaning of the regulatory text. The CMMC PMO continues to communicate with defense contractors and subcontractors, to include small businesses, and other members of the public. The official website of the DoD CMMC Program is <https://DoDcio.defense.gov/CMMC/> . This website contains links to CMMC documents including, but not limited to, the CMMC Model Overview, CMMC Scoping Guidance (by level), CMMC Level 1 Self-Assessment Guide, CMMC Level 2 Assessment Guide, and the CMMC Glossary. 17. C3PAO Consistency Comment: One commenter expressed concerns that C3PAOs would not conduct CMMC assessments in a uniform manner, leading to inconsistent results. Response: C3PAOs use only certified CMMC assessors to perform CMMC assessments. To ensure assessments are conducted in a uniform manner, assessors are trained by certified instructors and required to pass CMMC assessor tests before becoming certified. The accredited CAICO manage and oversee the training, testing, authorizing, and certifying of candidate assessors and instructors. A CAICO must meet the DoD requirements set forth in § 170.10 and achieve compliance with ISO/IEC 17024:2012, Conformity Assessment-General Requirements for Bodies Operating Certification of Persons Conformity Assessment. 18. CMMC Cost Impacts

), by expressly limiting the scope of the requirement to provide DoD with access to only such information that is 'necessary to conduct a forensic analysis,' and by affirmatively requiring the Government to safeguard any contractor attributional/proprietary information that has been shared (or derived from information that has been shared) against any unauthorized access or use. In the event that the contractor believes that there is information that meets the criteria for mandatory reporting, but the contractor desires not to share that information due to its sensitivity, then the

contractor should immediately raise that issue to the DoD points of contact (i.e., contracting officer, contracting officer's representative, or requiring activity) for the contract(s) governing the activity in question. Comment: The respondent commented that the ·rapidly reporting· requirement at DFARS 252.204-7012(c)(1)(2) is extremely burdensome on contractors. The respondent recommends either extending the period to report or, otherwise, amending the clause to explain that the 72-hour reporting period begins to run once a contractor knows or should have known that covered defense information (CDI) was adversely impacted or it is ·highly likely· that CDI was adversely impacted. The respondent also recommends that a medium assurance certificate need not be required for initial reporting, since this limits the person(s) within the entity who may report and may impede the ability to report within the requisite time period. Response: The contractor is required to report known or potential cyber incidents within 72 hours of discovery. Timeliness in reporting cyber incidents is a key element in cybersecurity and provides the clearest understanding of the cyber threat targeting DoD information. The 72-hour period has proven to be an effective balance of the need for timely reporting while recognizing the challenges inherent in the initial phases of investigating a cyber incident. Contractors should report available information within the 72-hour period and provide updates if more information becomes available. The requirement to have medium assurance certificates is important to communicate securely with DoD and to securely access DoD's reporting website. Comment: The respondent commented that there is often ambiguity as to what is considered CDI under specific contracts, which ought to be resolved by the Government, as agency personnel are best suited to identify the CDI being provided to a contractor and make appropriate notifications. The respondent recommended that DoD develop processes and procedures for engaging with contractors on the designation of information as CDI during the solicitation process or otherwise before the contract is finalized. Response: Processes already exist for the contractor to engage with DoD personnel to request clarification regarding CDI, both during the solicitation phase and during contract performance. Comment:

* * * In the case of any person (excluding farms and restaurants) who manufactures, processes, packs, transports , distributes, holds, or imports foods, the inspection shall extend to all records or other information described in section 414 when the Secretary has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals * * *. (Emphasis added.) FDA is imposing a record establishment and maintenance requirement on transporters to ensure that transporters have records that would assist FDA in a tracing investigation in a food-related emergency. (Comment 127) Numerous comments state that a requirement for specificity as to brand names, specific variety names (e.g., ·romaine lettuce· rather than ·lettuce·), lot numbers, and the way the food is packaged would require information neither readily available to transporters, nor routinely recorded by transporters. They further state that, if needed, such information could be obtained from both the shipper and receiver. They contend that these requirements are not necessary to effectuate the purposes of the statute. Other comments state that air carriers typically rely on information from those tendering the freight and, in some instances, shipments may not even be identified as containing food, particularly since chewing gum and pet foods are included in the definition of food. (Response) The final rule does not require transporters to establish and maintain records with brand name or lot numbers. However, FDA believes it is necessary to obtain some information about the shipment of food from transporters to conduct tracing investigations. Transporters are responsible for knowing that they are transporting food. (Comment 128) Some comments state that requiring brand name descriptions raises cargo security concerns because having more detailed descriptions on paperwork will increase the risk of theft and make it easier for bioterrorists to target certain shipments. (Response) FDA does not agree with this comment. Interstate transporters are already required to keep similar records under the DOT regulations, and FDA is not aware of these records presenting a security risk; thus, there should not be any increased security risks as a result of this rulemaking. Furthermore, FDA notes that the final rule does not require transporters to establish and maintain records of brand name, specific variety names, or lot numbers. K. Comments on What are the Record Retention Requirements? (Proposed §1.360)

5. Maintenance Agency. Department of Commerce, National Institute of Standards and Technology, Information Technology Laboratory (ITL). 6. Applicability. This standard is applicable to all Federal agencies that use cryptography-based security systems to protect sensitive information in computer and telecommunication systems (including voice systems) as defined in Section 5131 of the Information Technology Management Reform Act of 1996, Public Law 104-106. This standard shall be used in designing and implementing cryptographic modules that Federal departments and agencies

operate or are operated for them under contract. Cryptographic modules that have been approved for classified use may be used in lieu of modules that have been validated against this standard. The adoption and use of this standard is available to private and commercial organizations. 7. Applications. Cryptography-based security systems may be utilized in various computer and telecommunication applications (e.g., data storage, access control and personal identification, network communications, radio, facsimile, and video) and in various environments (e.g., centralized computer facilities, office environments, and hostile environments). The cryptographic services (e.g., encryption, authentication, digital signature, and key management) provided by a cryptographic module are based on many factors that are specific to the application and environment. The security level to which a cryptographic module is validated must be chosen to provide a level of security appropriate for the security requirements of the application and environment in which the module will be utilized and the security services that the module will provide.

including efforts to reduce risks from physical privacy and security threats, insider threats, and other related human risk management concerns. Such efforts are outside of the scope of this document. For ease of use, the remainder of this document will use the term 'CPLP' to refer to all elements of cybersecurity and privacy awareness, training, and educational activities to include other programs with titles such as awareness training, practical exercises (e.g., tabletop exercises, role-playing simulations, cyber ranges, or phishing campaigns), topic-based training, role-based training, and educational programs. It is not necessary for organizations to rename their programs as CPLP; this term is applied generically. The previous version of SP 800-50 defined awareness, training, and education as separate elements in a learning continuum. Research efforts [6][7] conducted with Federal Government training managers have shown that these terms have different meanings and can lead to confusion when describing the broader purpose of building a CPLP. While some managers may refer to programs as 'awareness and training' or 'awareness training,' the terms are applied inconsistently across organizations. Regardless of what an organization calls its program, the overarching goal of a CPLP is to provide opportunities for learning at all levels or stages of one's career. It is about creating programs where learning can take place. This Special Publication also uses the term 'learner' to describe individuals in any of the learning program audience segments. The term 'learner' can be found in SP 800-181r1 [5], where it refers to an individual who is acquiring specialized knowledge or developing a skill. This definition is useful here since it describes all participants in a 'learning program.' This document will refer to the program as a CPLP or CPLPs, as some organizations may require multiple programs to fulfill the learning requirements of the entire workforce.

Individual access . Access to information pertaining to the individual by the individual or his or her designated agent or legal guardian. (j) Lost, stolen, or compromised information . Actual or possible loss of control, unauthorized disclosure, or unauthorized access of personal information where persons other than authorized users gain access or potential access to such information for an other than authorized purpose where one or more individuals will be adversely affected. Such incidents also are known as breaches . (k) Maintain . To maintain, collect, use, or disseminate records contained in a system of records. (l) Non-Federal agency . Any state or local government, or agency thereof, which receives records contained in a system of records from a source agency for use in a computer matching program. (m) Official use . Within the context of this part, this term is used when officials and employees of a DoD Component have a demonstrated a need for the record or the information (printed page 18760) contained therein in the performance of their official duties, subject to DoD 5200.1-R. [5] (n) Personal information . Information about an individual that identifies, links, relates, or is unique to, or describes him or her, e.g., a social security number; age; military rank; civilian grade; marital status; race; salary; home/office phone numbers; other demographic, biometric, personnel, medical, and financial information, etc. Such information also is known as personally identifiable information (i.e., information which can be used to distinguish or trace an individual's identity, such as their name, social security number, date and place of birth, mother's maiden name, biometric records, including any other personal information which is linked or linkable to a specified individual). (o) Privacy Act request . A request from an individual for notification as to the existence of, access to, or amendment of records pertaining to that individual. These records must be maintained in a system of records. (p) Member of the public . Any individual or party acting in a private capacity to include Federal employees or military personnel. (q) Recipient agency . Any agency, or contractor thereof, receiving records contained in a system of records from a source agency for use in a computer matching program. (r) Record . Any item, collection, or grouping of information, whatever the

storage media (e.g., paper, electronic, etc.), about an individual that is maintained by a DoD Component, including, but not limited to, his or her education, financial transactions, medical history, criminal or employment history, and that contains his or her name, or the identifying number, symbol, or other identifying particular assigned to the individual, such as a finger or voice print or a photograph. (s) Risk assessment . An analysis considering information sensitivity, vulnerabilities, and cost in safeguarding personal information processed or stored in the facility or activity. (t) Routine use

The estimated Government costs utilize the entity numbers and phased roll-out detailed in the Public cost section. The DIBCAC estimated the detailed hours for all activities and other costs in a manner similar to the details shown in the Public cost section. Labor efforts for the Government are focused on Level 3. For purposes of the cost estimate, Government labor is based on the average of step one, five, and ten for GS-11 through GS-15 labor elements for the Washington DC area. The cost of labor was increased by a factor of approximately 51 percent which includes an estimated fringe factor (fringe factor includes estimated average insurance and pension benefits) plus overhead (overhead factor represents supervision and management of the labor) to arrive at the estimated labor rates. The Government labor in this estimate is performed by DCMA, which is a labor-intensive agency with limited overhead expenses. Therefore, the overall added factor of 51 percent is appropriate versus a typical full overhead factor of 100 percent. CMMC Database Infrastructure Costs The Government will develop the operational CMMC instantiation of eMASS. The cost analysis assumes that the nonrecurring engineering (NRE) cost includes the requirements development, architecture design, security, prototyping and testing, and approvals or certifications. [52] Nonrecurring engineering costs is a one-time fee of \$4,631,213 and is reflected here as incurred in the initial year of the estimate. The Year 1 amount is based on the actual cost incurred in FY2020 with adjustment for inflation to arrive at base year (BY) 1 dollars (2023). The recurring engineering (RE) cost includes database management, data analysis, cybersecurity, storage and backups, licensing, and infrastructure. [53] The cost for recurring engineering in Year 1 (\$2,336,038) and Year 2 (\$1,804,480) are based on historical (printed page 83191) amounts incurred for FY 2020 and FY 2021 with adjustment for inflation to arrive at base year 1 and Year 2 dollars (2023 and 2024). The estimated recurring engineering for Year 3 forward is calculated as the average of the Year 1 and Year 2 amounts $(\$2,336,038 + \$1,804,480)/2 = \$2,070,259$. The table summarizes the nonrecurring engineering (NRE) and recurring engineering (RE) costs for Year 1 through Year 5: Total Government Costs The following is a summary of the total Government costs over a ten-year period: Total Public and Government Costs The following is a summary of the total estimated annual Public and Government cost associated with implementation of the CMMC Program over a ten-year period: (printed page 83192) Alternatives

Contractors will advise all cleared employees, including those assigned to USG locations or operations outside the United States, of their individual responsibility for classification management and for safeguarding classified information. Contractors will provide security training to cleared employees consisting of initial briefings, refresher briefings, and debriefings in accordance with §.117.12. (h) Security reviews .(1) USG reviews. The applicable CSA will conduct recurring oversight reviews of contractors' NISP security programs to verify that the contractor is protecting classified information and implementing the provisions of this rule. The contractor's participation in the security review is required for maintaining the entity's eligibility for access to classified information. (i) Review cycle. The CSA will determine the scope and frequency of security reviews, which may be increased or decreased consistent with risk management principles. (ii) Procedures. (A) The CSA will generally provide notice to the contractor of a forthcoming review, but may also conduct unannounced reviews at its discretion. The CSA security review may subject contractor employees and all areas and receptacles under the control of the contractor to examination. (B) The CSA will make every effort to avoid unnecessary intrusion into the personal effects of contractor personnel. (C) The CSA may conduct physical examinations of the interior space of containers not authorized to secure classified material. Such examinations will always be accomplished in the presence of a representative of the contractor. (iii) Controlled unclassified information (CUI). 32 CFR part 2002 requires agencies to implement CUI requirements, but compliance with CUI requirements is outside the scope of the NISP and this rule. However, CSAs may conduct CUI assessments in conjunction with NISP USG reviews when: (A) The contractor is a participant in the NISP based on a requirement to access classified information; (B) A classified contract under the CSA's cognizance includes provisions for access to, or protection or handling of, CUI; and (C) The CSA has provided the contractor with specific guidance

regarding the assessment criteria and methodology it will use for overseeing protection of the CUI being accessed, stored or transmitted by the contractor as part of the classified contract. (2) Contractor reviews. Contractors will review their security programs on a continuing basis and conduct a formal self-inspection at least annually and at intervals consistent with risk management principles.

The study found that the academic medical center experienced, among other things, significant increases in the number of patients admitted, ambulance arrivals, waiting room times, and patients leaving without being seen. The study's authors concluded that their findings suggested that health care cyberattacks such as ransomware are associated with greater disruptions to regional hospitals and should be treated as disasters, necessitating coordinated planning and response efforts. [155] Thus, implementing reasonable and appropriate security measures better protects not only the regulated entity and its ePHI, but other regulated entities with whom it interacts, and may reduce the effects of cyberattacks and other security incidents that adversely affect the confidentiality, integrity, or availability of ePHI. As discussed above, several industry organizations have published and maintained compilations of voluntary standards, guidelines, best practices, methodologies, procedures, and processes for protecting the security of sensitive and confidential information, including PHI. Additionally, certain Federal health programs now either require or recommend the adoption of specific criteria that are intended to protect the confidentiality, integrity, and availability of ePHI. For example, the Health IT Certification Program maintained by the Assistant Secretary for Technology Policy and Office of the National Coordinator for Health Information Technology (ASTP/ONC) [156] sets minimum requirements for certified health IT, including criteria that pertain to cybersecurity. [157] These criteria are included in the Health IT Certification Program's Health IT Privacy and Security Framework, [158] which identifies when technical capabilities to support the privacy and security of electronic health information [159] must be included in certified health IT products. Additionally, health care providers that participate in certain Federal health programs must use health IT certified to these requirements. [160] Regulated entities also may want to consider adoption of certified health IT because it could contribute to compliance with the Security Rule. We will continue to work across the Department to ensure the adoption of consistent requirements for Federal programs that support the secure electronic exchange of health information to the extent that such consistency is appropriate. Throughout this preamble, we provide examples of how a regulated entity's participation in other Federal programs that require the use of health IT certified through the ONC Health IT Certification Program, or adoption of other Federal recommendations, such as the HHS CPGs, might support their compliance with the proposals in this NPRM.

3.2.1. 3.2.1 Improving Estimation Based on Knowledge of Prior Events Information about previous risk events may be helpful when estimating the likelihood and impact of those in the future.

Neither FAR clause 52.204-21 nor DFARS clause 252.204-7012 provide for DoD assessment of a defense contractor or subcontractor's implementation of the information protection requirements within those clauses. Defense contractors represent that they will implement the requirements in NIST SP 800-171 R2 upon submission of their offer. Findings from DoD Inspector General report (DODIG-2019-105 -Audit of Protection of DoD Controlled Unclassified Information on Contractor-Owned Networks and Systems-) indicate that DoD contractors did not consistently implement mandated system security requirements for safeguarding CUI and recommended that DoD take steps to assess a contractor's ability to protect this information. CMMC adds new assessment requirements for contractor implementation of underlying information security requirements, to allow DoD to assess a defense contractor's cybersecurity posture using authorized or accredited C3PAOs. The contractor and subcontractor must achieve the required CMMC Level as a condition of contract award. Inadequate Implementation of Cybersecurity Requirements Under DFARS clause 252.204-7012 and DFARS clause 252.204-7020, defense contractors and subcontractors must document implementation of the security requirements in NIST SP 800-171 R2 in a system security plan and may use a plan of action to describe how and when any unimplemented security requirements will be met. For the CMMC Program, the solicitation and resulting contract, will specify the required CMMC Status, which will be determined considering program criticality, information sensitivity, and severity of cyber threat. Although the security requirements in NIST SP 800-171 R2 address a range of threats, additional requirements are needed to significantly reduce the risk posed by APTs. An APT is an adversary that possesses sophisticated levels of expertise and significant resources that allow it to create opportunities to achieve its objectives by using multiple attack vectors (e.g., cyber, physical, and deception). CMMC Level 3 requires

implementation of selected security requirements from NIST SP 800-172 Feb2021 to reduce the risk of APT threats. The CMMC Program will require prime contractors to flow the appropriate CMMC Status requirement down throughout the entire supply chain relevant to a particular contract. Defense contractors or subcontractors that handle FCI, must meet the requirements for CMMC Level 1. Defense contractors that handle CUI must meet the requirements for CMMC Level 2 or higher, depending on the sensitivity of the information associated with a program or technology being developed.

Insufficient Scale and Depth of Resources To Verify Compliance

In addition, FDA recognizes that an activity such as placing a raw agricultural commodity directly into consumer-ready packages is likely to provide better protection to fragile produce, such as berries, than placing the produce into a larger bin or box for transport off the farm, with consumer packaging of the produce further down the distribution chain. ·Manufacturing/processing· as defined in § 1.328 means ·making food from one or more ingredients, or synthesizing, preparing, treating, modifying or manipulating food, including food crops or ingredients.· Thus, simply placing produce into containers (such as clamshells, baskets, mesh bags, or plastic bags) is more akin to packing, even if the containers are ultimately received by the consumer. Under § 1.328 of this final rule, a farm may engage in this packing activity so long as all of the involved produce is grown or consumed on the farm or a farm (printed page 71588) under the same ownership. Accordingly, a farm that simply places a raw agricultural commodity into containers, such as placing berries in clamshells, is not ·manufacturing/processing.· Finally, a farm that transports its products from the field does not cease to be a ·farm· because such transportation is considered incidental to traditional farming activities. (Comment 68) One comment states that FDA's definition of ·farm· should be size-neutral, and apply equally to integrated livestock and poultry facilities, as long as the activities engaged in at such locations are limited to ·growing or raising· farm animals for human food, but do not extend to further processing of food-producing animals into meat, milk, or eggs (such as occurs at food processing and packing plants and rendering facilities) for subsequent commercial sale for humans or animals. (Response) The proposed rule's definition of ·farm· had no size limitation, and neither does the final rule's definition. FDA agrees that integrated livestock and poultry facilities are ·farms,· to the extent that these operations are devoted to raising animals for food, the growing of crops, or both, and otherwise engage in only those activities included in the farm definition. FDA considers milking cows and collecting eggs from chickens to be ·harvesting· when applied to animals, because these activities are akin to harvesting crops. 5. Food

printed page 71593) 16. Transporter There were no comments on this definition. However, FDA is changing the definition to make clear that foreign persons that transport food in the United States are subject to these requirements regardless of whether they have possession, custody, or control of that food for the sole purpose of transporting that food. 17. Transporter's Immediate Previous Source There were no comments on this definition. 18. Transporter's Immediate Subsequent Recipient There were no comments on this definition. 19. You There were no comments on this definition. F. Comments on Do Other Statutory Provisions and Regulations Apply? (Proposed § 1.329) There were no comments on this issue. G. Comments on Can Existing Records Satisfy the Requirements of This Subpart? (Proposed § 1.330) (Comment 79) Several comments state that the final rule requires additional or more detailed data than what is already maintained and recommend that the FDA and CBP work together with industry to avoid any unnecessary burdens. A few comments requested that we also work closely with TSA and FAA as those agencies consider modifications of their own rules. The comments urge close coordination between the FDA and those other agencies to avoid inconsistent or redundant regulations. Several comments state that the proposed regulations do not strike a proper balance in that some of the data elements requested are unnecessary (redundant) and too burdensome on an industry already highly regulated by several agencies requiring the same or similar information. For example, the air cargo industry currently establishes and maintains industry air waybills, bills of lading and commercial invoices, which are required by CBP to be maintained for a period of 5 years. Moreover, CBP will be proposing a new set of mandatory advanced notice information, including other data elements, that could satisfy FDA in its effort to establish a complete tracing of activities. (Response) FDA based the requirements of the final rule on what records are needed by the Secretary for inspection to help the Secretary identify the immediate previous sources and the immediate subsequent recipients of food, including its packaging, to address credible threats of serious adverse health consequences or death to humans or animals. Section 1.330 of subpart J of this final rule states that duplication of existing records is not required if those records contain all of the information required by subpart J. If a person keeps records of all of the information as required by subpart J to comply with other Federal, State, or

local regulations (including those of TSA or FAA), or for any other reason, then those records may be used to meet these requirements. In addition, where a person currently has existing records that contain some, but not all, of the required information, only records for the nonexisting information needs to be created.

3.2.2 includes a more complete discussion of factors to consider when determining monitoring frequencies. 3.2.2. 3.2.2 ESTABLISH MONITORING AND ASSESSMENT FREQUENCIES Determining frequencies for security status monitoring and for security control assessments are critical functions of the organization's ISCM program.

The analysis also considers logging data, data in media, and issues associated with time, location, and sensitive data. In addition, the relevance of topics such as rapid elasticity, multi-tenancy, and hypervisor/virtual machine layers is discussed. These 62 challenges support the criminal justice and civil litigation systems, security incident response, and internal enterprise operations. Information Systems Audit and Control Association CSA designed the EA with the understanding that business requirements must guide the architecture. In the case of the EA, these requirements come from a controls matrix driven by regulations (e.g., Sarbanes-Oxley [17] and Gramm-Leach-Bliley [18]), standards frameworks (e.g., ISO-27002 [7], Payment Card Industry Data Security Standards [19]), and IT Audit Frameworks (e.g., COBIT [20]), all in the context of cloud service delivery models, such as SaaS, platform as a service (PaaS), and infrastructure as a service (IaaS). From these requirements, a set of security capabilities have been defined and organized according to the following best practice architecture frameworks:

For an IoT device such as a smart appliance, a device cybersecurity capability could be the ability to establish, manage, and enforce authentication and authorization for entities that attempt to access the device or its data. A corresponding non-technical supporting capability could be manufacturer-provided instructions on how authentication and authorization policies can be established and managed through or for the device. 1. Does the organization require Personal Identity Verification (PIV) card-based authentication or does it allow password-based authentication in limited circumstances? Support for critical cybersecurity technologies and operations that are used to implement security controls may be important for an organization in deciding which, if any, IoT device to use for a particular purpose. Organizations should note that some of this support, such as support for PIV may be related to standards and guidelines like the Federal Information Processing Standards (FIPS) 15 . 2. Does the organization purchase products from particular manufacturers or 3 rd parties? Such situations may limit the IoT devices readily available to the organization. This may, in turn, limit availability of IoT devices that best support the needs and goals of the organization. 3. Are there any environmental considerations (e.g., exposure to the elements, human presence, sensitive data that could be collected) in the environment of operation? Environmental considerations can help guide device cybersecurity requirements, particularly around physical protections. For example, if an IoT device is meant to be placed outdoors, a durable housing may be needed to withstand excessive heat, cold, and moisture while still providing data availability and integrity. 2. Does the IoT device lack key device cybersecurity requirements?

ives), there need to be different tiers of metrics based on the audience or user. For example, the CWE structure could be used to define security requirements that lead to associated security metrics. Jason noted that CWEs for hardware are relatively new, starting around 2020, compared to CWEs' long track record for software, which started around 2006. Since CWEs point out common root cause weaknesses that lead to vulnerabilities, they foster a more proactive approach by allowing security issues to be discovered and mitigated earlier in the hardware development life cycle, thus lowering the financial impact. Having good metrics that can be used to inform design and business decisions would be helpful to the semiconductor community. Finally, Mark Tehranipoor from the University of Florida emphasized the importance of thinking about security and associated metrics in the early stages of the hardware development life cycle. Specifically, this involves conducting a security and risk assessment and developing a

Transclassified Foreign Nuclear Information TP transportation plan UK United Kingdom UL Underwriters' Laboratories U.S.C. United States Code USD (I&S) Under Secretary of Defense for Intelligence and Security USG United States Government USML United States Munitions List VAL visit authorization letter VT voting trust (b) Definitions. Unless otherwise noted, these terms and their definitions are for the purposes of this rule. Access means the ability and opportunity

to gain knowledge of classified information. Access Permittee means the holder of an Access Permit issued pursuant to the regulations set forth in 10 CFR part 725, Permits For Access to Restricted Data. ACCM are security measures used by USG agencies to safeguard classified intelligence or operations when normal measures are insufficient to achieve strict need-to-know controls and where SAP controls are not required. Adverse information means any information that adversely reflects on the integrity or character of a cleared employee, that suggests that his or her ability to safeguard classified information may be impaired, that his or her access to classified information clearly may not be in the interest of national security, or that the individual constitutes an insider threat. Affiliate means each entity that directly or indirectly controls, is directly or indirectly controlled by, or is under common control with, the ultimate parent entity. Agency(ies) means any Executive agency as defined in 5 U.S.C. 105; any Military department as defined in 5 U.S.C. 102; and any other entity within the executive branch that releases classified information to private sector entities. This includes component agencies under another agency or under a cross-agency oversight office (such as ODNI with CIA), which are also agencies for purposes of this rule. Alarm service company means an entity or branch office from which all of the installation, service, and maintenance of alarm systems are provided, and the monitoring and investigation of such systems are either provided by its own personnel or with personnel assigned by this location. Alarm system description form means a form describing an alarm system and monitoring information. Approved security container means a GSA approved security container originally procured through the Federal Supply system. The security containers bear the GSA Approval label on the front face of the container, which identifies them as meeting the testing requirements of the assigned federal specification and having been maintained according to Federal Standard 809. Approved vault means a vault built to Federal Standard 832 and approved by the CSA. AUS community consists of the Government of Australia entities and Australian non-governmental facilities identified on the DDTC website (<https://pmdtdc.state.gov/>) at the time of export or transfer. Authorized person

The DoD has reviewed § 170.17(c)(2)(ii) and does not agree that a noun is missing. The lead-in paragraph provides the noun, and it is not necessary to repeat the phrase. The DoD disagrees that portions of § 170.18(c)(1) are redundant and therefore did not delete the lower level paragraphs, however revisions were made to clarify that a Level 2 certification assessment is needed prior to Level 3 certification assessment. Recommended edits to § 170.24(9) that would change the meaning were not accepted. During the assessment process, the Lead Assessor/Assessor must view any prior DoD CIO adjudication of proposed variances to security requirements in the system security plan to ensure correct implementation and render a determination of MET if there have been no changes in the environment. The DoD did not modify § 170.10 to permit CCAs, CCPs, and CCIs to retrain or recertify, instead of both, upon significant change to DoD's CMMC Program requirements under this rule. The DoD disagreed with one commenter's assertion that the summary within the preamble to the rule implies CMMC assessments address all DFARS clause 252.204-7012 requirements, therefore no edits were necessary. The rule indicates that the applicable CMMC Level 2 security requirements are those in NIST SP 800-171 R2 as implemented in DFARS clause 252.204-7012. Revisions suggesting that all objectives identified in NIST SP 800-171A Jun2018 need not be met are not accurate and not incorporated. Each assessment objective in NIST SP 800-171A Jun2018 must yield a finding of MET or NOT APPLICABLE for the overall security requirement to be scored as MET. Assessors exercise judgment in determining when sufficient and adequate evidence has been presented to make an assessment finding. This is consistent with current DIBCAC High Assessments and assessments conducted under the Joint Surveillance Voluntary Assessment Program (JSVAP). A security requirement can be applicable, even with assessment objectives that are N/A. The security requirement is NOT MET when one or more applicable assessment objectives is NOT MET. Recommendations to address specific contractual matters were not addressed, because this is a 32 CFR part 170 CMMC Program rule and not an acquisition regulation. Any comments related to contract requirements should be provided in response to the 48 CFR part 204 CMMC Acquisition rule. The CMMC rule does not specify the number of POA&Ms that may be used to address one or more CMMC security requirement that were NOT MET during a CMMC assessment. The OSA may choose to use a single POA&M or multiple POA&Ms.

Disclosures for law enforcement purposes. (1) Records may be disclosed to another Agency or an instrumentality of any Governmental jurisdiction within or under the control of the United States for a civil or criminal law enforcement activity, provided: (i) The civil or criminal law enforcement activity is authorized by law; (ii) The head of the law enforcement activity or a designee has made a written request specifying the particular records desired and the law

enforcement purpose (such as criminal investigations, enforcement of a civil law, or a similar purpose) for which the record is sought; and (iii) There is no Federal statute that prohibits the disclosure of the records. (2) Blanket requests for any and all records pertaining to an individual shall not be honored absent justification. (3) When a record is released to a law enforcement activity under this subparagraph, the disclosure accounting (see § 310.25) for the release shall not be made available to the individual to whom the record pertains if the law enforcement activity requests that the disclosure not be disclosed. (4) The blanket routine use for law enforcement (Appendix C, Section A) applies to all DoD Component systems notices (see paragraph (b)(6) of this section). This permits Components, on their own initiative, to report indications of violations of law found in a system of records to a law enforcement activity. (5) Disclosures may be made to Federal, State, or local, but not foreign law enforcement agencies. Disclosures to Foreign law enforcement agencies may be made if a routine use has been established for the system of records (printed page 18773) from which the records are to be released. (h) Emergency disclosures. (1) Records may be disclosed if disclosure is made under compelling circumstances affecting the health or safety of any individual. The affected individual need not be the subject of the record disclosed. (2) When such a disclosure is made, the Component shall notify the individual who is the subject of the record. Notification sent to the last known address of the individual as known to the Component is sufficient. (3) The specific data to be disclosed is at the discretion of the Component. (4) Emergency medical information may be released by telephone. (i) Disclosures to Congress. (1) Records may be disclosed to either House of the Congress or to any committee, joint committee or subcommittee of Congress if the release pertains to a matter within the jurisdiction of the committee. Disclosure is only authorized when in response to an official request on behalf of either House, committee, subcommittee, or joint committee. (2) Requests from members of Congress who are seeking records in their individual capacity or on behalf of a constituent. (i) Requests made in their individual capacity. Request for records shall be processed under the provisions of DoD 5400.7-R. (ii) Requests made on behalf of constituents.

Each of the legal U.S. cleared entities must comply no more than six months from the effective date of this NISPOM rule. During that six months, each legal cleared entity has the opportunity to review existing classified contracts to determine if there is any impact that they want to discuss with the applicable GCAs about possible equitable adjustment. Decisions on any requests for equitable adjustment will be made by the applicable contracting officer. Legal entities enter into contracts, licenses or grants; it is estimated that the average of 8,036 small business cleared entities are each a legal entity. It is estimated that each of those small business cleared legal entities will review an average of 3 existing classified contracts for possible equitable adjustment for a total of 24,108 contracts requiring 3 hours each for review in 2021. Using the published Office of Personnel Management GS salary schedule for FY20, the estimated labor rate for an FSO of a small business entity firm is the equivalent of a GS11 step 5 and for an FSO of a large business entity as the equivalent of a GS13, step 5. Of the large business entities, it is estimated that 2,100 large business cleared entities are legal entities, while the remaining large business entities are divisions or branch offices. It is estimated that each of those large business cleared legal entities will review an average of 30 existing classified contracts for possible equitable adjustment for a total of 63,000 contracts requiring 8 hours each for review in 2021. It is estimated that it will take more time for review by the (printed page 83307) large business cleared entities due to more complicated contracts. These assumptions imply costs of \$54.96 million in year one and no further costs as this action is taken only in the first year. c. Train SECRET cleared employees on requirements to submit foreign travel reports. The FSO at each entity (small or large) must ensure that its SECRET cleared employees are trained on the requirements. Such training by the FSO is estimated to take 1 hour in 2021 and a half an hour in each of the following years up to year 20. Using the published Office of Personnel Management GS salary schedule for FY20, the estimated labor rate for an FSO of a small business entity firm is the equivalent of a GS11 step 5 and for an FSO of a large business entity as the equivalent of a GS13, step 5. These assumptions imply total costs of \$0.99 million in 2021 as year one; and, \$0.49 million in each year 2 through 20. d. Submit foreign travel reports and receive any pre-travel threat briefings or post travel briefings based on the threat.

Preserve and protect images for suspected CUI incidents and submit media and data for damage assessments. If a suspected or confirmed CUI incident has occurred on an information system, the CUI clause requires the Contractor shall preserve and protect images of all known affected information systems and all relevant monitoring and packet capture data for at least 90 days from

the submission of the report to allow the Government to request the media and data or decline interest during this 90-day period, after which, if no request has been made, the images need no longer be preserved. Cooperate with Validation Actions for Non-Federal Information Systems. The CUI clause requires the Contractor to cooperate with validation actions conducted by an agency in accordance with NIST SP 800-171A, Assessing Security Requirements for Controlled Unclassified Information, and if applicable, NIST SP 800-172A for enhanced security requirements. These types of validation actions are similar to the DoD's Strategic High Confidence Level Assessments being conducted by DoD pursuant to the clause at DFARS 252.204-7020, and NIST SP 800-171 DoD Assessment Requirements, whereby the Government reviews the system security plan description of how (printed page 4289) each security requirement is met and the contractor demonstrates its implementation. While cooperating with validation actions, a contractor may need to provide the Government access to its facilities, systems, and personnel. Comply with NIST SP 800-53. The CUI clause requires the Contractor, when it is operating an information system identified in the SF XXX as a Federal information system that processes, stores, or transmits CUI identified in the contract, to comply with agency-identified security controls from NIST Special Publication 800-53 and any CUI Specified requirements identified in the SF XXX. In addition, cloud service providers must meet security requirements established by the Government for the Federal Risk and Authorization Management Program (FedRAMP) Moderate Baseline (<https://www.fedramp.gov/documents/>). The total estimated cost of compliance for small businesses is \$937,017,841 in the initial year of implementation and \$564,187,237 in each subsequent year. The cost per entity is dependent on whether the small business is required to implement NIST SP 800-171 Revision 2 or NIST SP 800-172 on their information systems. For more information on the specific compliance requirements and the expected cost impact on contractors, see section IV.C. of this preamble. A Regulatory Impact Analysis that includes a detailed discussion and explanation about the assumptions and methodology used to estimate the cost of this regulatory action, including the specific impact and costs for small businesses, is available at www.regulations.gov (search for FAR Case 2017-016 click Open Docket, and view Supporting Documents).

, 251 F. 3d 219, 224 (D.C. Cir. 2001). Section 306 of the Bioterrorism Act amends the FD&C Act by adding section 414 to the FD&C Act. In section 414, food is used in conjunction with other words to describe which FDA-regulated articles are subject to recordkeeping and access requirements. In describing the conditions for record access by FDA, section 414(a) of the FD&C Act requires a reasonable belief as to an article of food. In describing the purpose for which recordkeeping may be required, section 414(b) of the FD&C Act refers to food, including its packaging. Elsewhere in the recordkeeping provisions, section 414 of the FD&C Act refers to food, food safety, a food to the extent it is within the exclusive jurisdiction of [USDA], and recipes for food. The Bioterrorism Act is silent as to the meaning of food. Congress did not specify whether it intended the definition in section 201(f) of the FD&C Act to apply, one of the other possibilities noted in the previous paragraph, or another meaning. Where, as here, the statutory language on its face does not clearly establish Congressional intent, it is appropriate to consider not only the particular statutory language at issue, but also the language and design of the statute as a whole. *Martini v. Federal Nat'l Mortgage Association*, 178 F. 3d 1336, 1345 (D.C. Cir. 1999), citing *K Mart Corp. v. Cartier, Inc.*, 486 U.S. 281 (1988). Indeed, the analysis should not be confined to the specific provision in isolation because the meaning or ambiguity of a term may be evident only when considered in a larger context. *FDA v. Brown & Williamson Tobacco Corp.*, supra at 132 (2000). FDA has considered other sections of the Bioterrorism Act and has concluded that the meaning of food in the Bioterrorism Act is ambiguous. FDA previously considered the meaning of food in section 305 of the Bioterrorism Act, governing registration of food facilities, and concluded that it is ambiguous (68 FR 58894). Section 305 of the Bioterrorism Act amends the FD&C Act by adding section 415 to the FD&C Act (21 U.S.C. 350d). In section 415(a)(1) of the FD&C Act, the word food is modified by the phrase for consumption in the United States. It is not clear whether this modifying phrase limits the definition of food to food that is ingested, a narrower definition of food than that in section 201(f) of the FD&C Act. In addition, the definition of facility in section 415(b)(1) of the FD&C Act exempts farms; restaurants; other retail establishments. It is not clear whether the phrase other retail establishments includes retailers of food contact materials; the legislative history indicates that it does not, (printed page 71585) thereby giving rise to additional ambiguity about which definition of food applies to section 415. FDA also considered the meaning of food in section 307 of the Bioterrorism Act, governing prior notice of imported food shipments, and concluded that it is ambiguous (68 FR 58974

Requesters may obtain a copy of the supporting statement from the General Services Administration, Regulatory Secretariat Division by calling 202-501-4755 or emailing GSARegSec@gsa.gov. Please cite OMB Control Number 9000-XXXX, Controlled Unclassified Information, in all correspondence. List of Subjects in 48 CFR Parts 1, 2, 3, 4, 5, 7, 9, 11, 12, 15, 27, 33, 42, 52, and 53 Government procurement William F. Clark, Director, Office of Government-wide Acquisition Policy, Office of Acquisition Policy, Office of Government-wide Policy. Therefore, DoD, GSA, and NASA propose amending 48 CFR parts 1, 2, 3, 4, 5, 7, 9, 11, 12, 15, 27, 33, 42, 52, and 53 as set forth below: 1. The authority citation for 48 CFR Parts 1, 2, 3, 4, 5, 7, 9, 11, 12, 15, 27, 33, 42, 52, and 53 continues to read as follows: Authority: 40 U.S.C. 121(c); 10 U.S.C. chapter 4 and 10 U.S.C. chapter 137 legacy provisions (see 10 U.S.C. 3016); and 51 U.S.C. 20113. PART 1-FEDERAL ACQUISITION REGULATIONS SYSTEM 2. In section 1.106 amend in the table following the introductory text, by adding in numerical order, entries for 52.204-WW and 52.204-XX to read as follows: 1.106 OMB approval under the Paperwork Reduction Act. * * * * * FAR segment OMB control No. *...*...*...*...* 52.204-WW 9000-XXXX 52.204-XX 9000-0182 and 9000-XXXX *...*...*...*...* * * * * PART 2-DEFINITIONS OF WORDS AND TERMS 3. Amend section 2.101 by: a. Adding in alphabetical order the definitions for Contractor-attributional information, Controlled unclassified information (CUI), CUI incident, CUI Registry, Federal information system, and Information system; and b. Removing the definition for Federally controlled information system. The additions read as follows: 2.101 Definitions. * * * * * Contractor-attributional information means information that identifies the contractor or its employees directly or identifies them indirectly by grouping information that can be traced back to the contractor (e.g., program description or facility locations). * * * * * Controlled unclassified information (CUI) means information that the Government creates or possesses, or that an entity creates or possesses for or on behalf of the Government, that a law, regulation, or Governmentwide policy requires or permits an agency to handle using safeguarding or dissemination controls. CUI does not include: (1) Classified information; (2) Covered Federal information (see 4.404-1); (3) Information a contractor possesses and maintains in its own systems that did not come from, or was not created or possessed by or for, an executive branch agency or an entity acting for an agency (see 32 CFR 2002.4); or (4) Federally-funded basic and applied research in science, technology, and engineering at colleges, universities, and laboratories in accordance with National Security Decision Directive 189. * * * * * (printed page 4291) CUI incident means suspected or confirmed improper access, use, disclosure, modification, or destruction of CUI, in any form or medium. CUI Registry

'Since we have a lot of our personnel in remote areas, we've been doing it through our learning management system primarily for the annual security awareness training.' (D05) 'For our main enterprise network, it's computer-based training that's taken annually. But for those who don't have access to the enterprise network often for certain other networks that we might maintain, those are physical briefings done by the ISSOs [information system security officers] to those personnel. And then they sign an acknowledgment form.' (D03) 'You've got IT security, physical security, personnel security, etc. And they have their own training requirements-It's inefficient.' (S11)

Provide a marketplace with usage-based models for users to identify and implement the infrastructure solutions based on their business requirements with an appropriate chargeback model. Accelerate Cloud Adoption: Empower users with cloud offerings to meet their mission needs, e.g., scalability and agility. Provide best practice guidance on cloud models, e.g., hybrid and transition strategies based on the unique needs across Centers and Offices. Ensure Service Availability: Provide stable access to IT services through proactive, continuous monitoring of IT infrastructure service performance (e.g., Service Level Agreements, Operating Level Agreements) and feedback from FDA users to identify potential problems and implement targeted improvements. Implement Zero Trust Approach: Establish a comprehensive zero trust and risk-based approach to obtain optimal maturity level by upgrading, modernizing, and enhancing FDA's security and cyber defenses. Goal 3: Modernize Enterprise Services and Capabilities: Optimize the IT services portfolio to support everyday needs with cross-cutting, mission-critical offerings and benefit from economies of scale. Ensure enterprise IT services are stable, resilient, and adaptive, with opportunities for stakeholders to tailor solutions, where appropriate, and feedback loops to drive continuous improvement. Objectives Increase Business Alignment: Lead with a business-first approach to modernizing enterprise services and capabilities to ensure technology enables the capabilities defined in FDA's Business Capability Model and supporting business processes. Scale Operations:

Develop and drive adoption of enterprise solutions for standard capabilities, e.g., Finance/Budget, Human Resources, Acquisitions, Inspections, Freedom of Information Act requests, and Complaints Management with continuous user testing, while providing flexibility for customization where relevant. Manage the lifecycle of applications within the enterprise portfolio. Increase Digital Maturity: Maximize the use of technology (e.g., data, automation) in core business areas and enable processes to improve their ability to adapt to changes and scale. Improve Customer Experience: Create customer-centric solutions that enhance satisfaction by improving accessibility to IT solutions, including external-facing systems (e.g., Electronic Submission Gateway Next Generation), streamlining processes, and easing adoption. Increase stakeholder engagement with FDA IT services by prioritizing customer and employee feedback and establishing formal feedback loops. Modernize FDA Cybersecurity Defenses: Upgrade, enhance, and modernize FDA's critical cyber defenses and practices to address the evolving threat landscape where risks to FDA's critical assets, industry, and sensitive data exist. Reduce Technology Debt: Decommission legacy systems, applications, and End-of-Life devices and reinvest in enterprise solutions and business process improvements to minimize technical debt and enterprise risk. Goal 4:

Sources of cybersecurity risks include individual criminals, organized crime, terrorists, and nation-states. Cyber intrusions and attacks are mounted against commercial and individual users, as well as against government, military, and critical infrastructure networks (e.g., energy, water, sewage, transportation, banking, and financial networks). These intrusions and attacks often seek to steal, manipulate, destroy, or deny access to sensitive data and sometimes attempt to disable or disrupt individual systems. [1] Media outlets regularly report on the activities of those who disseminate viruses, spyware, and other malware, as well as those who spoof e-mail addresses, distribute spam, phish for sensitive personal information, and create botnets. [2] Cyber threats can originate from anywhere in the world. They not only target computers, but also mobile phones and other devices connected to the Internet. Cybersecurity risks seem to evolve as rapidly as the Internet expands, and those risks are becoming increasingly global in nature. Keeping pace with cybersecurity risks requires all users, even the most sophisticated users, to be aware of the threats and improve upon their security practices on an ongoing basis. Creating incentives to motivate all parties in the Internet economy to make appropriate security investments in response to risks they face requires a careful balance of technical and public policy measures. The constantly evolving nature of the threats and vulnerabilities not only affects individual firms and their customers, but collectively the threats pose a persistent economic and national security challenge. Computing devices are highly and increasingly interconnected, meaning that security deficiencies in a limited number of systems can be exploited to launch cyber intrusions or attacks on other systems. Put another way, poor cyber ·hygiene· on one Internet-connected computer negatively impacts other connected computers. Given the breadth and importance of this challenge, government and private sector actors have for many years been pursuing a range of mitigation strategies. Currently at the Federal level, the White House's Cybersecurity Coordinator is responsible for setting a national agenda and for coordinating Executive Branch cybersecurity activities. Specific Federal activities in this area include research and training, threat reporting and analysis, information collection and dissemination, consumer awareness, and policy development. In addition, the Director of the Office of Management and Budget (OMB) is responsible for overseeing Federal agency information security policies and practices under the Federal Information Security Management Act of 2002.

The OSA must complete and achieve a MET result for all security requirements specified in §·170.14(c)(2). No POA&Ms are permitted for CMMC Level 1. The OSA must conduct a self-assessment in accordance with the procedures set forth in paragraph (c)(1) of this section and submit assessment results in SPRS. To maintain compliance with CMMC Level 1 Self-Assessment requirements, the OSA must conduct a self-assessment of CMMC Level 1 on an annual basis and submit the results in SPRS. (i) SPRS inputs. The self-assessment results in the Supplier Performance Risk System (SPRS) shall include, at minimum, the following items: (A) CMMC Level. (B) Assessment Date (C) Assessment Scope. (D) All industry CAGE code(s) associated with the information system(s) addressed by the CMMC Assessment Scope (E) Compliance result. (ii) CMMC status revocation. If the CMMC PMO determines that the provisions of Level 1 of this rule have not been achieved or maintained, as addressed in §·170.6, a revocation of the validity status of the CMMC Level 1 Self-Assessment may occur. At that time, standard contractual remedies will apply and the OSA will be ineligible for additional awards with CMMC Level 1 Self-Assessment or higher requirements for the information system within the CMMC Assessment Scope until such time as a valid CMMC Level 1 Self-Assessment is achieved. (2) Affirmation. Affirmations are required for all CMMC Level 1 Self-Assessments.

Affirmation procedures are set forth in § 170.22. (b) Contract eligibility. Prior to award of any contract or subcontract with a CMMC Level 1 requirement, OSAs must comply with all CMMC Level 1 Self-Assessment requirements and have submitted an affirmation of compliance into SPRS for all information systems within the CMMC Assessment Scope. (c) Procedures. (1) Self-Assessment. The OSA must perform a CMMC Level 1 Self-Assessment scored in accordance with the CMMC Scoring Methodology described in § 170.24. The Level 1 Self-Assessment must be performed in accordance with the CMMC Level 1 scope requirements set forth in § 170.19(a) and (b) and the following: (i) NIST SP 800-171A. The CMMC Level 1 Self-Assessment must be performed using the objectives defined in NIST SP 800-171A (incorporated by reference, see § 170.2) for the security requirement that maps to the CMMC Level 1 security requirement as specified in table 1 to paragraph (c)(1)(ii) of this section. In any case where an objective addresses CUI, FCI should be substituted for CUI in the objective. (ii) Mapping Table for CMMC Level 1 security requirements to the NIST SP 800-171A objectives. Table 1 to § 170.15(c)(ii). CMMC Level 1 Security Requirements to NIST SP 800-171A CMMC Level 1 security requirements as set forth in § 170.14(c)(2) NIST SP 800-171A AC.L1-b.1.i 3.1.1 AC.L1-b.1.ii 3.1.2 AC.L1-b.1.iii 3.1.20 AC.L1-b.1.iv 3.1.22 IA.L1-b.1.v 3.5.1 IA.L1-b.1.vi 3.5.2 MP.L1-b.1.vii 3.8.3 PE.L1-b.1.viii 3.10.1 First phrase of PE.L1-b.1.ix (FAR b.1.ix.*) 3.10.3 Second phrase of PE.L1-b.1.ix (FAR b.1.ix.*) 3.10.4

The authors, Tim Grance and Joan Hash of the National Institute of Standards and Technology (NIST), and Marc Stevens, Kristofor O'Neal, and Nadya Bartol, of Booz Allen Hamilton (BAH), wish to thank their colleagues who reviewed the many drafts of this document and contributed to its technical content. We also gratefully acknowledge and appreciate the many comments we received from readers of the public and private sectors, whose valuable insights improved the quality and usefulness of this document. The authors would like to specifically acknowledge some key organizations whose extensive feedback substantially contributed to the development of the document. These organizations include: Environmental Protection Agency, Department of Treasury, Tennessee Valley Authority, and Electronic Data Systems. The authors would also like to acknowledge Ron Ross, Gary Stoneburner, Curtis Barker, Ron Tencati, Marianne Swanson, and Bill Burr of NIST, Alexis Feringa, Don Ottinger, Skip Hirsh, and Robert Young, BAH, and Shirley Radack for their extensive review and comment and keen and insightful assistance throughout the development of the document. Organizations frequently must evaluate and select a variety of information technology (IT) security services in order to maintain and improve their overall IT security program and enterprise architecture. IT security services, which range from security policy development to intrusion detection support, may be offered by an IT group internal to an organization, or by a growing group of vendors. Organizations can benefit when choices among services and service providers stimulate competition and bring innovation to the marketplace. However, it is difficult and challenging to determine service provider capabilities, measure service reliability and navigate the many complexities involved in security service agreements.

IA.L2-3.5.7 · Password Complexity CMMC Assessment Guide · Level 2 | Version 2.13 127 FURTHER DISCUSSION Password complexity means using different types of characters as well as a specified number of characters. This applies to both the creation of new passwords and the modification of existing passwords. Characters to manage complexity include numbers, lowercase and uppercase letters, and symbols. Minimum complexity requirements are left up to the organization to define. Define the lowest level of password complexity required. Define the number of characters that must be changed when an existing password is changed. Enforce these rules for all passwords. Salting passwords adds a string of random characters (salt) to a password prior to hashing. This ensures the randomness of the resulting hash value. Example You work with management to define password complexity rules and ensure they are listed in the company's security policy. You define and enforce a minimum number of characters for each password and ensure that a certain number of characters must be changed when updating passwords [a,b]. Characters include numbers, lowercase and uppercase letters, and symbols [a]. These rules help create hard-to-guess passwords, which help to secure your network. Potential Assessment Considerations · Is a degree of complexity specified for passwords, (e.g., are account passwords a minimum of 12 characters and a mix of upper/lower case, numbers, and special characters), including minimum requirements for each type [a,b,c]? · Is a change of characters required when new passwords are created [d]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.5.7

DoD is proposing to add a new DFARS contract clause that allows for an expedited contract closeout agreement between the contractor and the Government that will save administrative costs for both the

contractor and the Government. The clause will be used when the contracting officer intends to expedite the contract closeout process by having the contractor and the Government waive entitlement to any residual dollar amounts up to \$1,000 at the time of final contract closeout. The objective of the rule is to reduce the amount of time and money expended on reconciling small dollar residual dollar amounts in order to close out contracts.

II. Discussion and Analysis The proposed DFARS clause 252.204-70XX, Expediting Contract Closeout, provides an agreement by the Government and contractor to waive any entitlement that otherwise might accrue to either party in any amount of \$1,000 or less at the time of final contract closeout. The new clause will be prescribed at DFARS 204.804-70 for use in solicitations and contracts, including those under FAR part 12 procedures for acquisition of commercial items, when the contracting officer intends to expedite contract closeout through such a waiver.

III. Applicability to Contracts at or Below the Simplified Acquisition Threshold and for Commercial Items, Including Commercially Available Off-the-Shelf Items This rule proposes to create a new clause DFARS 252.204-70XX, Expediting Contract Closeout. DoD plans to apply this clause to solicitations and contracts for the acquisition of commercial items, including commercially available off-the-shelf items, and to acquisitions valued at or below the simplified (printed page 19720) acquisition threshold. These categories of acquisitions are those most likely to benefit from expedited contract closeout.

IV. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, or reducing costs, or harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866 , Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804 .

V. Executive Order 13771 This rule is not expected to be subject to E.O. 13771 , because this rule is not a significant regulatory action.

VI. Regulatory Flexibility Act DoD does not expect this proposed rule to have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601 , et seq. An initial regulatory flexibility analysis (IRFA) has been performed and is summarized as follows:

(9) SP 800-171 revision 2, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, published February 2020 (includes updates as of January 28, 2021); IBR approved for §§ 170.4(b); 170.14(a), (b), and (c). (10) SP 800-171A, Assessing Security Requirements for Controlled Unclassified Information, published June 2018; IBR approved for §§ 170.11(a), 170.14(d), 170.15(c), 170.16(c), 170.17(c). (11) SP 800-172, Enhanced Security Requirements for Protecting Controlled Unclassified Information: A Supplement to NIST Special Publication 800-171, published February 2021; IBR approved for §§ 170.5(a) and 170.14(a) and (c). (12) SP 800-172A, Assessing Enhanced Security Requirements for Controlled Unclassified Information, published March 2022; IBR approved for §§ 170.4(b), 170.14(d), and 170.18(c).

(b) The Committee on National Security Systems (CNSS), National Security Agency, Savage Road, Suite 6165, Fort George G. Meade, MD 20755-6716; 410-854-6805; www.cnss.gov/CNSS/issuances/Instructions.cfm . (1) Committee on National Security Systems Instruction No. 4009, Committee on National Security Systems (CNSS) Glossary, published March 2022; IBR approved for § 170.4(b). (2) [Reserved]. (c) International Organization for Standardization (ISO) Chemin de Blandonnet 8, CP 401-1214 Vernier, Geneva, Switzerland; +41 22 749 01 11; www.iso.org/popular-standards.html . (1) ISO/IEC 17011:2017, Conformity assessment-Requirements for accreditation bodies accrediting conformity assessment bodies, published 2017; IBR approved for §§ 170.8(b) and 170.98(b). (2) ISO/IEC 17020:2012, Conformity assessment-Requirements for the operation of various types of bodies performing inspection, published 2012; IBR approved for §§ 170.8(a) and (b) and 170.9(a) and (b). (3) ISO/IEC 17024:2012, Conformity assessment-General requirements for bodies operating certification of persons, published 2012; IBR approved for §§ 170.8(b) and 170.10(a) and (b). Note to § 170.2(c): The American National Standards Institute (ANSI) IBR Portal provides access to standards that have been incorporated by reference in the U.S. Code of Federal Regulations at <https://ibr.ansi.org> . These standards incorporated by the U.S. government in rulemakings are offered at no cost in read only format and are presented for online reading. There are no print or download options. All users will be required to install the FileOpen plug-in and accept an online end user license agreement prior to accessing any standards.

§ 170.3 Applicability. (a) The requirements of this part apply to: (1) All DoD contract and subcontract awardees that will process, store, or transmit information that meets the standards for FCI or CUI on contractor information systems; and, (2) Private-sector businesses or other entities comprising the CMMC Assessment and Certification Ecosystem, as

specified in subpart C of this part.

From the NIST SP 800-172 Rev 3 Final Public Draft: 9 Nonfederal organizations that collect or maintain information on behalf of a federal agency or that use or operate a system on behalf of an agency must comply with the requirements in FISMA [11]. The enhanced security requirements address the protection of CUI by promoting penetration-resistant architecture, damage-limiting operations, and cyber resiliency.¹⁰ 10 Protecting the integrity and availability of the means used to achieve confidentiality protection is within the scope of this publication. While outside of the explicit purpose of this publication, the APT may seek to harm organizations, individuals, or the Nation by compromising the integrity and availability of CUI upon which mission and business functions depend, such as software that is categorized as CUI. The securi

Cryptographic Standards Data Encryption Validation Tests Message Authentication Code (MAC) Validation System Key Management Validation System (KMVS) . General Section 6 contains information regarding validated products for FIPS PUB 46-1, Data Encryption Standard (DES), FIPS PUB 113, Computer Data Authentication (Implements Message Authentication Code, ANSI X9.9), and FIPS PUB 171, Key Management Using ANSI X9.17. Product: Microsoft* Wndows NT· POSIX Subsystem Version 3.5.1 PCD: Microsoft* Wndows NT· POSIX Subsystem POSIX Conformance

Disclosure of records in the system could reveal the identity of confidential sources and result in an unwarranted invasion of the privacy of others. Disclosure may also reveal information relating to actual or potential criminal investigations. Disclosure of classified national security information would cause damage to the national security of the United States. Disclosure could also interfere with a civil or administrative action or investigation; reveal the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations; and reveal the confidentiality and integrity of Federal testing materials and evaluation materials used for military promotions when furnished by a confidential source. (D) Subsection (d)(2). Amendment of the records could interfere with ongoing criminal or civil law enforcement proceedings and impose an impossible administrative burden by requiring investigations to be continuously reinvestigated. (E) Subsections (d)(3) and (4). These subsections are inapplicable to the extent exemption is claimed from subsections (d)(1) and (2). (F) Subsection (e)(1). It is often impossible to determine in advance if investigatory records contained in this system are accurate, relevant, timely and complete, but, in the interests of (printed page 14735) effective law enforcement and counterintelligence, it is necessary to retain this information to aid in establishing patterns of activity and provide investigative leads. (G) Subsection (e)(2). To collect information from the subject individual could serve notice that he or she is the subject of a criminal investigation and thereby present a serious impediment to such investigations. (H) Subsection (e)(3). To inform individuals as required by this subsection could reveal the existence of a criminal investigation and compromise investigative efforts. (I) Subsection (e)(4)(G), (H), and (I). These subsections are inapplicable to the extent exemption is claimed from subsections (d)(1) and (2). (J) Subsection (e)(5). It is often impossible to determine in advance if investigatory records contained in this system are accurate, relevant, timely and complete, but, in the interests of effective law enforcement, it is necessary to retain this information to aid in establishing patterns of activity and provide investigative leads. (K) Subsection (e)(8). To serve notice could give persons sufficient warning to evade investigative efforts. (L) Subsection (g). This subsection is inapplicable to the extent that the system is exempt from other specific subsections of the Privacy Act. (iv) Exempt records from other systems.

https://www.himss.org/sites/hde/files/media/file/2022/01/28/2021_himss_cybersecurity_survey.pdf . Back to Citation 232. ·Muddling through cybersecurity: Insights from the U.S. healthcare industry,· supra note 116, p. 543. Back to Citation 233. Id. at 542. Back to Citation 234. · See 68 FR 8334 , 8352 (Feb. 20, 2003). In the preamble to the 2003 Security Rule, the Department explained that it had determined that an inventory requirement was unnecessary because it is redundant of other requirements. We assumed that covered entities (and later all regulated entities) would have performed this activity by virtue of having implemented the security measures required under the security management process standard. Back to Citation 235. ·Muddling through cybersecurity: Insights from the U.S. healthcare industry,· supra note 116, p. 542-543. Back to Citation 236. ·Eric C. Reese, ·Healthcare's cybersecurity stakes reach alarming levels,· Health Facilities Management Magazine, Volume 76, Issue 8, p. 22 (Nov. 2022). Back to Citation 237. 68 FR 8334 , 8343 (Feb. 20, 2003). Back to Citation 238. 45 CFR

164.308(a)(1)(ii)(A) . Back to Citation 239. 45 CFR 164.308(a)(1)(ii)(B) ; ·2016-2017 HIPAA Audits Industry Report,· supra note 121, p. 4. Back to Citation 240. ··2016-2017 HIPAA Audits Industry Report,· supra note 121, p. 4. Back to Citation 241. Id. at 11. Back to Citation 242. Id. at 27. Back to Citation 243. Id. at 30. Back to Citation 244. Id. at 27 and 30. Back to Citation 245. · See ·OCR News Releases & Bulletins,· Office for Civil Rights, U.S. Department of Health and Human Services, <https://www.hhs.gov/ocr/newsroom/index.html> . Back to Citation 246. · See Resolution Agreement, ·Doctors' Management Services, Inc.,· Office for Civil Rights, U.S. Department of Health and Human Services (Oct. 31, 2023), <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/dms-ra-cap/index.html> ; Press Release, ·HHS' Office for Civil Rights Settles Ransomware Cyber-Attack Investigation,· Office for Civil Rights, U.S. Department of Health and Human Services (Oct. 31, 2023), <https://www.hhs.gov/about/news/2023/10/31/hhs-office-civil-rights-settles-ransomware-cyber-attack-investigation.html> ; see also ·Breach Portal: Notice to the Secretary of HHS Breach of Unsecured Protected Health Information,· supra note 10. Back to Citation 247. ··HHS' Office for Civil Rights Settles Ransomware Cyber-Attack Investigation,· supra note 246. Back to Citation 248. · See Resolution Agreement, ·Montefiore Medical Center,· Office for Civil Rights, U.S. Department of Health and Human Services (Nov. 17, 2023), <https://www.hhs.gov/hipaa/for-professionals/compliance-enforcement/agreements/montefiore/index.html> ; ·HHS' Office for Civil Rights Settles Malicious Insider Cybersecurity Investigation for \$4.75 Million,· supra note 223. Back to Citation 249. ··Muddling through cybersecurity: Insights from the U.S. healthcare industry,· supra

(E) The fee provisions of E.O. 12600 apply when requesters ask for information about themselves under the Privacy Act of 1974. In these cases, the only assessable processing fees are for duplication. Components are reminded in these cases requesters may also be eligible for a waiver or reduction of fees if the fee waiver criteria are met. (3) To be as responsive as possible to FOIA requests while minimizing unwarranted costs to the taxpayer, the Components shall adhere to the following procedures: (i) Analyze each request to determine the category of the requester. If the Component determination regarding the category of the requester is different than that claimed by the requester, the Component shall: (A) Notify the requester to provide additional justification to warrant the category claimed, and that a search for responsive records will not be initiated until agreement has been attained relative to the category of the requester. Absent further category justification from the requester, and within a reasonable period of time (e.g., 30 calendar days), the Component shall render a final category determination and notify the requester of such determination, to include normal administrative appeal rights of the determination. (B) Advise the requester, notwithstanding any appeal, a search for responsive records will not be initiated until the requester indicates a willingness to pay assessable costs appropriate for the category determined by the Component. (ii) If these conditions are not met the request need not be processed and the requester shall be so informed. (iii) The Components must be prepared to provide an estimate of assessable fees if desired by the requester. While it is recognized that search situations will vary among Components, and that an estimate is often difficult to obtain prior to an actual search, requesters who desire estimates are entitled to such before committing to a willingness to pay. If Components' actual costs exceed the amount of the estimate or the amount agreed to by the requester, the amount in excess of the estimate or the requester's agreed amount shall not be charged without the requester's agreement. Even though Components do not need to advise requesters of their appeal rights when provided fee estimates, such estimates may be appealed and litigated by the requester. (iv) No DoD Component may require advance payment of any fee; i.e., payment before work starts or continued on a request, unless either of the following conditions are met: (A) The requester has a history of failing to pay fees in a timely fashion (within 30 days of the billing date) on a previous request (B) The Component determines that the fee will exceed \$250.00.

- Adaptable configurations : allowing for quick and secure changing of configurations within a security zone to support flexible manufacturing requirements. - Increased network resiliency : helping to provide and maintain an acceptable level of service availability in the face of misconfiguration and faults. Security zone-based architecture provides a standardized way of designing a scalable and consistent security architecture. It offers increased network resiliency, meaning it helps keep communications working in the face of misconfiguration and faults. Security segmentation can help mitigate the vulnerabilities listed above and should be part of a comprehensive cybersecurity plan.

Three commenters asked about sustainment of CMMC certification during the three-year certificate validity period. They wanted to know how sustainment will be monitored and whether demonstrating continuous monitoring capabilities would be considered in lieu of a strict three-year recertification period. There were also questions about what the criteria or triggers would be that would lead to a loss of accreditation during this period, including what happens when a company with a certification is acquired by another company, and whether contractors are required to notify the DoD if systems fall out of compliance with CMMC requirements. Response: The validity period is one (1) year for CMMC Level 1 and three (3) years for CMMC Levels 2 and 3. Contractors must continue to meet CMMC requirements during the period of performance of the contract. Under CMMC, contractors must submit affirmations into SPRS for each assessment, attesting that they have met the CMMC requirements and will maintain the applicable information systems at the required CMMC level as specified in § 170.22. Monitoring contractor compliance with the terms of the contract is the responsibility of the contractor, with the government contracting officer. DoD is not utilizing a continuous monitoring capability in lieu of compliance requirements. DoD understands that information systems operating in a CMMC Assessment Scope will require upgrades and maintenance. For systems certified at CMMC Level 2 or above, a plan for addressing deficiencies is defined in § 170.21. It is possible for an organization to need a new assessment during the validity period. CMMC self-assessments and certifications are valid for a defined CMMC Assessment Scope. If the CMMC Assessment Scope changes due to infrastructure modifications or expansion of the CMMC Assessment Scope due to new acquisition, a new assessment may be required. The original CMMC certification remains valid for the original CMMC Assessment Scope. The information system(s) in the new CMMC Assessment Scope may not be used to process, store, or transmit CUI for any contract until it is validated via a new CMMC assessment. The same applies to the annual affirmations. During the annual affirmation process, a senior organization official affirms that the organization is satisfying and will maintain the requirements of the specified CMMC level (e.g., CMMC Level 2 Self-Assessment). The affirmation applies to the CMMC Assessment Scope. At the time of a new self-assessment or certification, a new affirmation is submitted into SPRS affirming that the organization meets the CMMC requirements and will maintain the applicable information system (within the CMMC Assessment Scope) at the required CMMC level. For CMMC Levels 2 and 3, an affirmation is required to be submitted in SPRS annually for the duration of the triennial validity period and at the conclusion of any POA&M closeout assessments. Affirmation requirements are set forth in § 170.22.

State Medicaid agencies), would be required to: conduct a Security Rule compliance audit; report to covered entities or business associates, as applicable, upon activation of their contingency plan; deploy multi-factor authentication (MFA) in and penetration testing of relevant electronic information systems; complete network segmentation; disable unused ports and remove extraneous software; update cybersecurity policies and procedures; revise business associate agreements; and update workforce training. Business associates would be required to conduct an analysis and provide verification of their compliance with technical safeguards and covered entities would be required to obtain verification from business associates (and business associates from their subcontractors). Additionally, group health plans would need to revise plan documents to require plan sponsors to comply with administrative, physical, and technical safeguards according to the Security Rule standards. Finally, through contractual language, health plan sponsors would need to enhance safeguards for electronic protected health information (ePHI) according to the Security Rule standards. Costs for all regulated entities to change their policies and procedures alone would increase costs above the UMRA threshold in one year, and costs of health plan sponsors would increase total costs further. Although Medicaid makes Federal matching funds available for States for certain administrative costs, these are limited to costs specific to operating the Medicaid program. There are no Federal funds directed at Health Insurance Portability and Accountability Act of 1996 (HIPAA) compliance activities. The Department believes that pursuant to Subtitle E of the Small Business Regulatory Enforcement (printed page 993) Fairness Act of 1996, [938] the Office of Management and Budget's (OMB's) Office of Information and Regulatory Affairs would be likely to determine that when finalized, this rule meets the criteria set forth in 5 U.S.C. 804(2) because it is projected to have an annualized effect on the economy of more than \$100,000,000. The Justification for this Rulemaking and Summary of Proposed Rule Provisions section at the beginning of this preamble contain a summary of this rule and describe the reasons it is needed. We present a detailed analysis below. 1. Summary of Costs and Benefits

During Fiscal Year 2019 (FY 2019), from October 1, 2018 through September 30, 2019, the NIST

Information Technology Laboratory (ITL) Cybersecurity and Privacy Program successfully responded to numerous challenges and opportunities in security and privacy. This annual report highlights the FY 2019 research agenda and activities for the ITL Cybersecurity and Privacy Program, including: the ongoing participation and development of international standards; the enhancement of privacy and security risk management models, including those for the protection of controlled unclassified information (CUI), systems engineering and cyber resiliency, supply chains, and mobile technologies; the continued advancement of cryptographic technologies, including updates to Federal Information Processing Standard (FIPS) Publication 140-3, Security Requirements for Cryptographic Modules, and preparation for post-quantum cryptographic methods; and improved infrastructure protection in areas such as zero trust architectures and advanced networking security. NIST maintained a strong focus on supporting small and medium-sized businesses (SMBs), including updates to the Small Business Cybersecurity Corner website to make resources easier to find and use, and drawing on contributed cybersecurity resources and feedback received from federal partners and the public. - ISO JTC 1/SC 41, IoT architecture and vocabulary, IoT Interoperability, and IoT Applications; - ISO JTC 1/SC 27, IoT aspects of Security and Privacy; and - IETF, Software Updates for Internet of Things Security Area. Notable achievements during FY 2019 included updates to several NIST endeavors that are described below.

1. the results of a self-assessment of the OSA's implementation of the NIST SP 800-171 Rev 2 requirements set forth in 32 CFR 170.16 associated with the covered contractor information system(s) used in performance of the applicable contract. 2. an initial affirmation of compliance, and, if applicable, a POA&M closeout affirmation, and then annually thereafter, an affirmation of continued compliance set forth in 32 CFR 170.22 . 3. the Level 2 Self-Assessment cost burden will be addressed as part of the 48 CFR acquisition rule. CMMC Level 2-Certification Assessment CMMC Level 2 Certification requires compliance with the security requirements set forth in 32 CFR 170.17 to protect CUI. CMMC Level 2 does not add any additional security requirements to those identified in NIST SP 800-171 Rev 2. A CMMC Level 2 Certification Assessment of the applicable contractor information system(s) provided by an authorized or accredited C3PAO is required to validate implementation of the NIST SP 800-171 Rev 2 security requirements prior to award of any prime contract or subcontract and exercise of option. The C3PAO will upload the CMMC Level 2 results in eMASS which will feed the information into SPRS. OSCs will submit in SPRS an initial affirmation of compliance, and, if necessary, a POA&M closeout affirmation, and then annually thereafter, an affirmation of continued compliance as set forth in 32 CFR 170.22 . The Level 2 Certification Assessment cost burdens are included in this part with the exception of the requirement for the OSC to upload the affirmation in SPRS that is included in the Title 48 acquisition rule and an update to DFARS collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Additionally, the information collection reporting requirements for the CMMC instantiation of eMASS are included in a separate ICR for this part and cover only those requirements pertaining to the CMMC process. CMMC Level 3-Certification Assessment CMMC Level 3 Certification Assessment requires a CMMC Level 2 Final Certification Assessment and compliance with the security requirements set forth in 32 CFR 170.18 to protect CUI. CMMC Level 3 adds additional security requirements to those required by existing acquisition regulations as specified in this rule. A CMMC Level 3 Certification Assessment of the applicable contractor information system(s) provided by the DCMA Defense Industrial Base Cybersecurity Assessment Center (DIBCAC) is required to validate implementation of the DoD-defined selected security requirements set forth in NIST SP 800-172. A CMMC Level 2 Final Certification is a prerequisite to schedule a DIBCAC assessment for CMMC Level 3. DCMA DIBCAC will upload the CMMC Level 3 results into the CMMC instantiation of eMASS, which will feed the information into SPRS.

result in clients electing to use their own tools and products in lieu of the managed service provider. This commenter attached a list of more than a dozen commercial product and tools they use as examples associated with this concern. One commenter used their public comment submission to submit materials marketing services their company can provide, while another commenter suggested the rule direct readers to a website listing all software, tools, and applications deemed safe and cost effective by virtue of CMMC assessment. Another commenter asserted that all companies need access to cybersecurity solutions from DHS/CISA and grants to assist them in buying Zero Trust technologies to protect CUI. Similarly, some commenters recommended various other cybersecurity tools, programs, or technologies that could be used to meet CMMC security requirement and provide threat intelligence to DIB companies. Such recommendations included portals used in conjunction with perimeter and privileged access management systems. One commenter proposed delaying implementation of the CMMC

rule until all DoD contractors' system architectures could be analyzed for possible implementation of Virtual Machines, or Blockchain for secure data transmission, or hosting of all CUI on DoD hosted platforms. Response: The government cannot comment on specific products or vendors, including marketing materials submitted via public comment. However, companies that act as ESPs should note this rule does not require CMMC assessment or certification of ESPs that do not process, store, or transmit CUI. Services provided by an ESP are in the OSA's assessment scope. Comments pertaining to solutions available from other Federal agencies or expressing a desire for grants to obtain Zero Trust solutions or other cybersecurity solutions are also beyond the scope of the CMMC rule. A wide range of technologies may be used to implement CMMC requirements. DoD will not comment on specific OSA technology choices. The Department declines the recommendation to review the system architectures of all DoD contractors. The DoD did not modify the rule to identify a repository of ·safe and cost effective· software, applications, and tools because a CMMC assessment does not evaluate commercial products or services for those characteristics and the government does not provide product endorsements. 10. Applicability a. Systems Operated on Behalf of DoD and National Security Systems Comment:

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Health and Human Services Food and Drug Administration [Docket No. FDA-2012-N-0911] AGENCY: Food and Drug Administration, HHS. ACTION: Notice of a new system of records. SUMMARY: In accordance with the requirements of the Privacy Act of 1974 and the Food and Drug Administration's (FDA) regulations for the protection of privacy, FDA is publishing notice of a Privacy Act system of records entitled, ·FDA User Fee System, HHS/FDA,· System Number 09-10-0021. FDA utilizes the User Fee System (UFS) to collect fees pursuant to Federal law and FDA's implementing regulations. The records kept in this system relate to fees assessed under the Freedom of Information Act (FOIA), the Prescription Drug User Fee Act, the Medical Device User Fee and Modernization Act, the Animal Drug User Fee Act, the Animal Generic Drug User Fee Act, the Mammography Quality Standards Act, the Family Smoking Prevention and Tobacco Control Act, the Food Safety Modernization Act, the Biosimilar User Fee Act, the Generic Drug User Fee Act, and other fees assessed by FDA under its Federal Food, Drug and Cosmetic Act authority such as color additive certification fees and export certificate fees. For purposes of this notice, these fees are collectively referred to as user fees. DATES: Effective Date: The new system of records will be effective on November 14, 2012, with the exception of the routine uses. The routine uses will become effective on December 31, 2012. Submit either electronic or written comments by December 31, 2012. ADDRESSES: You may submit comments, identified by Docket No. FDA-2012-N-0911, by any of the following methods: Electronic Submissions Submit electronic comments in the following way: Federal eRulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. Written Submissions Submit written submissions in the following ways: Fax: 301-827-6870. Mail/Hand delivery/Courier (for paper or CD-ROM submissions): Division of Dockets Management (HFA-305), Food and Drug Administration, 5630 Fishers Lane, rm. 1061, Rockville, MD 20852. Instructions: All submissions received must include the Agency name and Docket No. FDA-2012-N-0911 for this notice. All comments received may be posted without change to <http://www.regulations.gov> , including any personal information provided. For additional information on submitting comments, see the ·Comments· heading of the SUPPLEMENTARY INFORMATION section of this document. Docket:

(f) If you are a transporter or nontransporter retaining records on behalf of a transporter, you must retain for 6 months after the dates you receive and release the food all required records for any food having a significant risk of spoilage, loss of value, or loss of palatability within 60 days after the date the transporter receives or releases the food. If you are a transporter, or nontransporter retaining records on behalf of a transporter, you must retain for 1 year after the dates you receive and release the food, all required records for any food for which a significant risk of spoilage, loss of value, or loss of palatability occurs only after a minimum of 60 days after the date the transporter receives or releases the food. (g) You must retain all records at the establishment where the covered activities described in the records occurred (onsite) or at a reasonably accessible location. (h) The maintenance of electronic records is acceptable. Electronic records are considered to be onsite if they are accessible from an onsite location. §1.361 What

are the record availability requirements? When FDA has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals, any records and other information accessible to FDA under section 414 or 704(a) of the act (21 U.S.C. 350c and 374(a)) must be made readily available for inspection and photocopying or other means of reproduction. Such records and other information must be made available as soon as possible, not to exceed 24 hours from the time of receipt of the official request, from an officer or employee duly designated by the Secretary of Health and Human Services who presents appropriate credentials and a written notice. §1.362 What records are excluded from this subpart? The establishment and maintenance of records as required by this subpart does not extend to recipes for food as defined in §1.328; financial data, pricing data, personnel data, research data, or sales data (other than shipment data regarding sales). (printed page 71655) §1.363 What are the consequences of failing to establish or maintain records or make them available to FDA as required by this subpart? (a) The failure to establish or maintain records as required by section 414(b) of the act and this regulation or the refusal to permit access to or verification or copying of any such required record is a prohibited act under section 301 of the act. (b) The failure of a nontransporter immediate previous source or a nontransporter immediate subsequent recipient who enters an agreement under §1.352(c) to establish, maintain, or establish and maintain, records required under §1.352(a) or (b), or the refusal to permit access to or verification or copying of any such required record, is a prohibited act under section 301 of the act.

(Comment 150) Several comments state that the Bioterrorism Act only provides authority to access and copy records for the purpose of determining whether a food believed to be adulterated is actually so and for conducting a tracing investigation in regard to such an adulterated food. Comments express concern over possible unlawful conduct and abuse of discretion by FDA field inspectors and other officials. They urge FDA to clearly define legal violations concerning recordkeeping and record access requirements so corporate officers can make responsible decisions. They also urge FDA to integrate the constitutionally required safeguards into the regulations. Comments recommend that FDA establish procedural safeguards to protect manufacturers and their customers by providing the affected company with a reasonable written notice that explains how the 'reasonable belief' standard is being met and identifies the type of records being requested. According to comments, this would inform the affected company which records are being sought and the legal basis for the request. Several comments also request that FDA develop procedures requiring that the written notice be examined and approved by the District Director in whose district the implicated food is located, or by any FDA official senior to such District Director. They urge FDA to develop guidelines to define 'reasonable belief' and base a decision to access records on laboratory analyses confirming adulteration and/or on an affidavit sworn under penalty of perjury. Other comments state that FDA should issue interim final regulations with an opportunity for comment on the procedural protections that will be utilized to implement the record maintenance and inspection provisions of the Bioterrorism Act. Specifically, the comments state that the regulations should at least delineate agency procedures for authorizing the review, those officials who are permitted to review the documents, the standard for when such review may occur, an appellate procedure for those who disagree with the agency's determination, and the reasonable times, limits and circumstances to which the Bioterrorism Act limits FDA's review, as well as the procedures FDA must implement to prevent the unauthorized disclosure of any trade secret or confidential information that is obtained by FDA under the Bioterrorism Act. Others urge FDA to incorporate these procedures into regulations and ask that the public be granted an additional 60 days to comment.

This draft special controls guidance document was developed to support the proposed classification of in vitro diagnostic devices for *Bacillus* spp. detection, a previously unclassified preamendments device, into class II (special controls). On March 7, 2002, the Microbiology Devices Panel (the Panel) recommended that in vitro diagnostic devices for *Bacillus* spp. detection be classified into class II. The Panel believed that class II with the special controls (guidance document and limitations on the distribution) would provide reasonable assurance of the safety and effectiveness of the device. After the panel meeting, FDA found three additional in vitro diagnostic devices for *Bacillus* spp. detection to be substantially equivalent to another device within that type. This device has the same intended use as its predicate device but makes use of newer nucleic acid amplification technology (NAAT). While NAAT detection devices exhibit technological differences from the preamendments *Bacillus* spp. detection devices, FDA has determined that they are as safe and effective as, and do not raise different questions of safety and effectiveness than, their predicates. (See section 513(i) of the Federal Food, Drug, and

Cosmetic Act (21 U.S.C. 360c(i)).) This draft guidance document identifies the proposed classification regulation and product code and issues of safety and effectiveness that require special controls. Elsewhere in this Federal Register , in its publication of the proposed classification regulation, FDA is including proposed distribution limitations as another special control. FDA believes that the special controls described in the draft guidance and the proposed regulation when combined with general controls will be sufficient to provide reasonable assurance of the safety and effectiveness of these devices. II. Significance of Special Controls Guidance Document FDA believes that adherence to the recommendations described in this guidance document, if finalized, in addition to general controls, and the special control in the proposed rule, if finalized, will provide reasonable assurance of the safety and effectiveness of in vitro diagnostic devices for *Bacillus* spp. detection classified under § 866.3045 (21 CFR 866.3045). If classified as a class II device under § 866.3045, an in vitro diagnostic device for *Bacillus* spp. detection will need to comply with the requirement for special controls; manufacturers will need to address the issues requiring special controls as identified in the guidance document or by some other means that provides equivalent assurances of safety and effectiveness as well as comply with any additional controls specified in the classification regulation itself. III. Electronic Access Persons interested in obtaining a copy of the draft guidance may do so by using the Internet. A search capability for all CDRH guidance documents is available at <http://www.fda.gov/MedicalDevices/DeviceRegulationandGuidance/GuidanceDocuments/default.htm> .

Twenty-two comments requested the government provide more guidance, preferably within RFPs or contracts, to better identify what will be considered CUI for that contract, and how it should be appropriately marked. One comment specifically noted a need for contractual instructions on whether data created in performance of a contract rises to the level of CUI. Another person asked when is does information created or possessed by a contractor become CUI. One comment asked whether digital or physical items derived from CUI are treated as CUI while another asked what specific information qualifies as CUI for OT and IoT assets. Another comment asked whether FCI and or CUI created or provided under a non-DoD agency contract, but which is also used in support of a DoD contract, would be subject to the applicable CMMC level requirement. Another comment noted that DoD focuses too narrowly on data security aspects of major system acquisition and largely fails to address securing data generated by operational and/or maintenance operations, such as invoices and bills of lading for operational support purchases. One comment stated there was a need for CUI policy guidance for the entire Federal Government. Another comment inferred, incorrectly, that the CMMC Accreditation Body makes determinations about what is and what is not CUI and stated that the Government should make those determinations. Another comment stated that to better address the needs of contractors tasked with safeguarding (printed page 83104) CUI, NARA should initiate a public comment period to reevaluate its CUI Registry. The comment also noted that NARA should identify when a CUI designation automatically applies to contractor-created information and revise the CUI Registry to stipulate that a specific basis in statute (or a contract) is required for information to be considered CUI. Another comment recommended a study be conducted on protections for systems and data at Confidential and higher classification levels and should assess whether NARA's CUI protection requirements (32 CFR part 2002) have yielded any real benefits in protecting critical data. Another comment stated that the CUI program is a costly proposition whose security value is questionable given data can still be compromised, even over systems with a CMMC assessment. The comment stated that if data is to be controlled for Critical Items, then the existing system used for CONFIDENTIAL information should suffice. Finally, another comment suggested that CUI information should be under the control of the Federal Government and access granted only to appropriately trained, and qualified contractors through a portal. Response: Neither the CUI program (established in E.O. 13556) nor the safeguarding requirements codified in its implementing directives are changed by virtue of the compliance assessment framework established by this rule.

(1) The list shall be considered Government data. At a minimum, the list shall include-

- (i) The identification and description of any controllers, relays, sensors, pumps, actuators, Open Platform Communications Unified Architecture devices, and other industrial control system devices; including, when available, the manufacturer, part number, software version, communication protocols, and all static IP addresses assigned to the different hardware components used in performance of the contract;
- (ii) An explanation of whether the device is password protected and, if so, whether the password can be changed from the default password provided by the manufacturer;
- (iii) An explanation of whether the device is accessible remotely (e.g., through internet or another network connection);
- (iv) Location information in enough detail to affirmatively locate the

operational technology equipment, if necessary; and (v) Whether multi-factor authentication is present and enabled. (2) The Contractor shall update the list to track any movement of the equipment during contract performance, as software or firmware updates are applied, when equipment is removed or taken out of service; or when equipment is added or placed into service. (3) Upon request by the Contracting Officer, the Contractor shall provide the Government a copy of the current and/or historical list(s). (l) Binding Operational Directives and Emergency Directives. (1) Except as identified in paragraph (l)(2) of this clause, the Contractor shall comply with the Binding Operational Directives (BODs) and Emergency Directives (EDs) issued by CISA and having a specific applicability to a FIS used or operated by a contractor. The list of BODs and EDs can be found at <https://www.cisa.gov/-directives>. (2) The following BODs and EDs that have a specific applicability to a FIS used or operated by a contractor will not apply to this contract: _____. [Contracting Officer to list any BODs or EDs not applicable to the contract, as specified by the requiring activity] (3) BODs and EDs with specific applicability to a FIS used or operated by a contractor that are issued after the date of award will be applied to this contract, at the Contracting Officer's discretion, through appropriate modification of the contract. (m) Indemnity for potential or actual loss or damage of Government data.

printed page 23533) a. The clause at DFARS 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, covers cyber incident reporting requirements for incidents that affect a covered contractor information system or the covered defense information residing therein, or that affects the contractor's ability to perform the requirements of the contract that are designated as operationally critical support and identified in the contract. b. DFARS provision 252.204-7008, Compliance with Safeguarding Covered Defense Information Controls, requires an offeror that proposes to vary from any of the security controls of National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 in effect at the time the solicitation is issued to submit to the contracting officer a written explanation of how the specified security control is not applicable or an alternative control or protective measure is used to achieve equivalent protection. c. DFARS provision 252.239-7009, Representation of Use of Cloud Computing, requires contractors to report that they ~~anticipate~~ or ~~do not anticipate~~ utilizing cloud computing service in performance of the resultant contract. The representation will notify contracting officers of the applicability of the cloud computing requirements at DFARS clause 252.239-7010 of the contract. d. DFARS clause 252.239-7010, Cloud Computing Services, requires reporting of cyber incidents that occur when DoD is purchasing cloud computing services. These DFARS provisions and clauses facilitate mandatory cyber incident reporting requirements in accordance with statutory regulations. When reports are submitted, DoD will analyze the reported information for cyber threats and vulnerabilities in order to develop response measures as well as improve U.S. Government understanding of advanced cyber threat activity. In addition, the security requirements in NIST SP 800-171 are specifically tailored for use in protecting sensitive information residing in contractor information systems and generally reduce the burden placed on contractors by eliminating Federal-centric processes and requirements. The information provided will inform the Department in assessing the overall risk to DoD covered defense information on unclassified contractor systems and networks. Affected Public: Businesses or other for-profit and not-for-profit institutions. Respondent's Obligation: Required to obtain or retain benefits. Number of Respondents: 2,017. Responses per Respondent: Approximately 17.35. Annual Responses: 34,974. Average Burden per Response: .29 hours. Annual Burden Hours: 10,071. Frequency: On occasion. Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. [FR Doc. 2019-10459 Filed 5-21-19; 8:45 am] BILLING CODE 5001-06-P

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The cybersecurity workforce shortfall is well documented. According to CyberSeek.org 1, there were 313 735 open cybersecurity-related positions from September 2017 through August 2018. The 2017 Global Information Security Workforce Study states that 1.8 million more cybersecurity professionals will be needed to accommodate the predicted global shortfall by 2022 [1]. The National Initiative for Cybersecurity Education (NICE) is addressing this critical issue by energizing and promoting a robust network and ecosystem of cybersecurity education, training, and workforce development. Supporting this mission, objective 3.3 of the NICE Strategic

Plan emphasizes guiding career development and workforce planning by facilitating state and regional consortia to identify cybersecurity pathways addressing local workforce needs [2]. - Industry Day - invite employers to learn more about the region's cybersecurity education initiatives, learn how to 'plug in' and assist, and network with area faculty and administrators. - Exhibit Booth - seek out industry stakeholders at established events or conferences to find a champion of the company and encourage employers to provide experiential learning if they want to hire experienced candidates.

One respondent stated that when DoD issued the proposed rule under DFARS case 2017-D019, DoD explained that the proposed rule would relieve the administrative burden on contractors by deleting the current regulations relating to performance-based payments at DFARS subpart 232.10 and the associated clauses at DFARS 252.232-7012 and 252.232-7013. This respondent recommended that DoD should repeal in their entirety the current DFARS regulations related to PBPs and the associated clauses, and any associated Procedures, Guidance, and Information (PGI), because existing FAR regulations are sufficient. Response: It is the intent of this rule to implement section 831 of the NDAA for FY 2017. The prior DFARS Case 2017-D019 presented a cohesive approach to contract financing, in order to increase DoD's business effectiveness and efficiency as well as to provide an opportunity for both small and other than small entities to qualify for increased customary progress payment rates and maximum performance-based payment rates, based on whether the offeror/contractor has met certain performance criteria. The provisions of that rule were interdependent upon each other, and DoD cannot segregate out specific aspects of that rule in the absence of the criteria that were intended to motivate performance. In response to the comment that DoD should repeal in their entirety the current DFARS regulations relating to performance-based payments, DoD does not consider this to be in the best interest of DoD or of contractors. DFARS coverage, as modified by this final rule, provides needed clarification and also provides flexibility with regard to security for performance-based payments. The following discussion will address more specific concerns about the proposed rule.

2. Make PBPs the Preferred Method of Contract Finance Many respondents stated that DoD should clearly establish PBPs as the default choice for contract financing.

a. Benefits of performance-based payments. Comment: Several respondents particularly emphasized the benefits of PBPs. These respondents stated that PBPs better align the interests of the Government and the contractors. According to these respondents, by effectively attributing the payments to the work performance, rather than just costs incurred, the Government receives tangible product deliverables and the (printed page 19683) contractor receives cash payment tied to performance, which encourages the timely execution of the contract. One respondent stated that PBPs may reduce costs for Government oversight and compliance, encourage nontraditional and small business entities to enter the Federal marketplace, and facilitate contractor financing and performance of contracts.

Response:

- for selecting the security controls necessary to satisfy the minimum security requirements. - SP 800-18 Guide for Developing Security Plans for Systems , describes the procedures for developing a system security plan, provides an overview of the security requirements of the system, and describes the controls in place or planned for meeting those requirements. - SP 800-30 Guide for Conducting Risk Assessments , provides guidance for conducting risk assessments of federal systems and organizations. - SP 800-34 Contingency Planning Guide for Federal Information Systems , assists organizations in understanding the purpose, process, and format of information system contingency plans (ISCPs) development with practical, real-world guidelines. - SP 800-37 Guide for Applying the Risk Management Framework to Systems: A Security Life Cycle Approach , provides guidelines for applying the Risk Management Framework to federal systems, including conducting the activities of security categorization, security control selection and implementation, security control assessment, system authorization, and security control monitoring. - SP 800-39 Managing Information Security Risk: Organization, Mission, and Information System View , provides guidelines to establish an integrated, organizationwide program for managing information security risk to organizational operations (e.g., mission, functions, image, and reputation), assets, individuals, other organizations, and the Nation resulting from the operation and use of federal systems. - SP 800-53 Security and Privacy Controls for Systems and Organizations , provides guidelines for selecting and specifying security controls for organizations and systems supporting the executive agencies of the Federal Government to meet the requirements of FIPS Publication 200.

The rule implements DoD statutory authorities and responsibilities to establish a program to protect DoD information and information systems, including information systems operated and maintained by contractors or others in support of DoD activities (see 10 U.S.C. 2224 ; and the Federal

Information Security Management Act (FISMA), codified at 44 U.S.C. 3541 et seq.). No change is made to the rule. Comment: Three comments asserted the rule should create an oversight and accountability structure that includes public, congressional, and executive branch reporting. One comment recommended using DHS oversight procedures as a model to ensure the program's compliance with regulations and relevant guidelines. Response: The DIB CS/IA program is subject to numerous procedures, (printed page 62432) requirements, and oversight to ensure compliance with DoD and national policies for collecting, handling, safeguarding, and sharing sensitive information with non-Government organizations in accordance with DoD Directive 5500.1, DoD Privacy Program and 5400.11-Regulation, Department of Defense Privacy Program, which proscribes uniform procedures for the DoD Privacy Program. For additional information regarding the Government's safeguarding of information received from the DIB companies, with specific focus on PII, see the Privacy Impact Assessment (PIA) for the DIB CS/IA Program (http://DoDcio.defense.gov/Portals/0/Documents/DIB%20CS-IA%20PIA_FINAL_signed_30jun2011_VMSS_GGMR_RC.pdf). In addition, DoD annually reports to Congress on the progress of DoD in defending the DoD and the Defense Industrial Base from cyber events. No additional oversight is warranted at this time. No change is made to the rule. Comment: One comment recommended distinguishing between classified and unclassified GFI, and that classified GFI should be handled per the NISPOM. Response: As stated in § 236.4(f) of the rule, GFI will be issued via both unclassified and classified means, and that handling and safeguarding of classified GFI shall be in compliance with the National Industrial Security Program Operating Manual (NISPOM) (DoD 5220.22-M). No change is made to the rule. Comment: One comment recommended not to apply sharing limitations under the rule to non-sensitive GFI. Response: As defined in the rule at § 236.2(j), Government Furnished Information (GFI) means information provided by the Government under the voluntary DIB CS/IA program, including but not limited to cyber threat information and information assurance practices. GFI is typically nonpublic information that is sensitive based either on the content of the information itself or the context in which the information is relevant (e.g., cyber threat information). Accordingly, the handling requirements applicable to GFI are designed to protect sensitive information. No change is made to the rule. Comment:

3.3.3 Perform Risk Assessment The Contractor shall collect the data required to support the risk assessment methodology and perform the risk assessment.

governs the applicability of laws to acquisitions at or below the SAT. Section 1905 generally limits the applicability of new laws when agencies are making acquisitions at or below the SAT, but provides that such acquisitions will not be exempt from a provision of law under certain circumstances, including when the FAR Council makes a written determination and finding that it would not be in the best interest of the Federal Government to exempt contracts and subcontracts in amounts not greater than the SAT from the provision of law. At the time of the final rule the FAR Council does not intend to make a determination to apply 15 U.S.C. 278g-3e to acquisitions at or below the SAT because paragraph (a)(2) of 15 U.S.C. 278g-3e expressly states that it applies to acquisitions in amounts not greater than the SAT; therefore, no additional determination is necessary under 41 U.S.C. 1905 . B. Applicability to Contracts for the Acquisition of Commercial Products and Commercial Services, Including Commercially Available Off-the-Shelf (COTS) Items 41 U.S.C. 1906 governs the applicability of laws to contracts for the acquisition of commercial products and commercial services, and is intended to limit the applicability of laws to contracts for the acquisition of commercial products and commercial services. Section 1906 provides that if the FAR Council makes a written determination that it is not in the best interest of the Federal Government to exempt commercial item contracts, the provision of law will apply to contracts for the acquisition of commercial products and commercial services. 41 U.S.C. 1907 states that acquisitions of COTS items will be exempt from certain provisions of law unless the Administrator for Federal Procurement Policy makes a written determination and finds that it would not be in the best interest of the Federal Government to exempt contracts for the procurement of COTS items. At the time of the final rule the FAR Council intends to make a determination to apply 15 U.S.C. 278g-3e to acquisitions for commercial products and commercial services. At the time of the final rule, the Administrator for Federal Procurement Policy intends to make a determination to apply 15 U.S.C. 278g-3e to acquisitions for COTS items. C. Determination(s) This rule applies to acquisitions for commercial products, including COTS items, and commercial services, because Government data and systems require protection regardless of dollar value or commerciality of the product or service. IV. Expected Impact of the Rule The Government anticipates that this rule will reduce administrative costs for contractors interested in providing services to develop, implement,

operate, or maintain a FIS. Over time, the FAR Council anticipates this proposed rule, once finalized, will increase competition by establishing a common set of policies and procedures that apply to FISs.

(Response) As discussed in response to comment 82 of this document, transporters are not required to establish and maintain the detailed information about a particular shipment of food that nontransporters are required to establish and maintain under §§ 1.1337 and 1.1345 of this final rule. The final rule provides five alternatives for interstate and intrastate transporters to meet their obligation to establish and maintain required records. (Comment 125) One comment notes that air transporters may have a record of the consignee (immediate subsequent recipient), but may not have a record of the truck transporter the consignee sent to pick up the freight. The comment believes that the consignee who arranged for the pickup should be responsible for the record, not the air transporter who released the shipment to the agent of the consignee. (Response) The final rule provides five alternatives for transporters to meet their obligation to establish and maintain records. Failure by the immediate previous source or immediate subsequent recipient who enters into an agreement under § 1.1352(e) of this final rule to keep such records is a prohibited act. The requirements for transporters in the final rule ensure that FDA has records identifying how a food traveled between a nontransporter supplier and nontransporter recipient when multiple transportation companies or multiple modes of transportation are used. FDA does not believe that the nontransporter will always have this information. For example, if a trucking company that picks up the food from a manufacturer in State A for delivery to a grocery store in State B subcontracts with an airline and subsequent trucking company to deliver the food to the grocery store, the manufacturer may have no knowledge that the food was transported on the airline and subsequent trucking company. Similarly, the grocery store is aware that the second trucking company delivered the food, but may not be aware that before that, the food was transported on an airline and a different trucking company. In the event that FDA has a reasonable belief that food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals, such records could be critical to determining whether such adulteration occurred during transportation, and if so, during which leg. (Comment 126) One comment observes that the Bioterrorism Act does not mention "transporters" in providing the Secretary with record access. The comment concludes that Congress chose not to give the Secretary access to the records of transporters and asks why there is a recordkeeping requirement for those transporters. (Response) FDA disagrees with this comment's assertion that the statute does not provide FDA with access to transporters' records. Section 306 of the Bioterrorism Act amends section 704(a) of the FD&C Act, Factory Inspection, to read:

Enterprise Campus Network (red de las instalaciones de la empresa). Internal App Server (servidor de aplicaciones interno). Database (base de datos). Internet (Internet). Employees (empleados). Employee (empleado). Contractor Service Tech (técnico de servicio de contratistas). Contracted HVAC (contratación de climatización). Conference Center (centro de conferencias). Visitors (visitantes).

CMMC Acquisition rule, while one similar comment suggested that CMMC level 3 certification costs should be allowable when CMMC level 3 requirements are initially implemented. One comment addressed cyber incident reporting timelines for cloud service providers and recommended that the DoD's FedRAMP moderate equivalency policy be revised to align with DFARS clause 252.204-7012 timelines. Another asked whether the rule inadvertently omitted requirements to assess compliance with DFARS clause 252.204-7012 cyber incident requirements. Other commenters asked for the CMMC contract clause verbiage, as was subsequently published in the related 48 CFR part 204 CMMC Acquisition rule. For example, some people asked whether CMMC requirements would be levied in ID/IQ contract awards versus task order awards, and GSA schedules. They asserted that adding CMMC clauses in GSA schedules might inadvertently allow contracting officers to include them in non-DoD issued task orders. Another opined that ID/IQ contracting procedures might necessitate changing the CMMC level needed for the base contract after its initial award, based on the needs of a task order. One commenter incorrectly inferred that a single Program Manager would make the CMMC level and type determination for every task order issued against an ID/IQ. In addition, two comments suggested that the DoD communicate with every current DoD contractor to identify which CMMC level would apply to their existing contracts. One company identified their specific DoD contract and asked whether it would be cancelled absent CMMC compliance. Another asked whether a current DFARS clause 252.204-7020 self-assessment score could be submitted to meet a CMMC level 2 self-assessment requirement. They also recommended elimination of the DFARS clause 252.204-7020 requirements when CMMC is implemented. One commenter speculated about whether DoD's CMMC contract clauses can be applied to DoD contractors

that also make and sell the same product to other US Government agencies. They noted that export licenses do not restrict companies from providing product data to other parties and posited that this might conflict with CMMC requirements. One person asked about the potential for conflicts between CMMC clauses and the Berry amendment and suggested that Berry amendment compliance take precedence over CMMC clauses. Response: Some comments received lacked relevance to the rule's content, which is limited to specific CMMC program requirements. Changes to FAR and DFARS requirements are out of scope of the 32 CFR part 170 CMMC Program rule, as contractual changes would occur under the 48 CFR part 204 CMMC Acquisition rule. This rule does not discuss the Berry Amendment. The rule does not address recovery of assessment costs because it does not make any change to 48 CFR 31.201-2. This 32 CFR part 170

DCMA DIBCAC assessors are trained and qualified to conduct assessment against NIST SP 800-171 R2 for the DoD. DoD determined that C3PAOs conducting assessments on other C3PAOs introduced a significant conflict of interest. Given the sensitivity of the programs requiring Level 3 assessments, the DoD determined that those assessments must be completed by a DoD entity. The DoD declines to respond to speculative or editorial comments regarding DCMA DIBCAC assessments. The CMMC model (§170.14) only incorporates requirements from FAR clause 52.204-21, NIST SP 800-171 R2, and NIST SP 800-172 Feb2021. C3PAOs are only responsible for assessing the requirements of §170.17. DCMA DIBCAC operates under different authorities and can address all the requirements of DFARS clause 252.204-7012. d. Validity Period for Standards Acceptance Comment: Two comments asked how SPRS would be updated to reflect CMMC Level 2 certification when based on standards acceptance. One asked whether that update would be automatic. One comment asked whether CMMC standards acceptance for (printed page 83148) DIBCAC joint surveillance assessments would result in certifications being issued to the OSA by the C3PAO or by DIBCAC. Some comments, including those from three industry associations, objected to the start date for the 3-year validity of CMMC certification based on standards acceptance of prior DIBCAC assessments. Those comments requested the validity period begin with the effective date of the 32 CFR part 170 CMMC Program rule. Along these lines, another commenter asked whether C3PAOs may certify an OSA based on evidence of a perfect 110-scored DIBCAC High Assessment. One comment requested a 1-year extension of the validity period to 4 years. Response: The DoD has considered the recommendation to modify the validity period for certifications resulting from standards acceptance and declines to revise the rule text. It is important that contractors maintain security compliance for systems that process, store, or transmit DoD CUI. Given the evolving cybersecurity threat, DoD's best interests are served by ensuring that CMMC Level 2 assessments remain valid for no longer than a 3-year period, regardless of who performs the assessment. A C3PAO may not simply read the DIBCAC assessment score in SPRS and grant a completed CMMC Level 2 certification assessment. C3PAOs may only submit certification assessment results based on having conducted a certification assessment. An OSA is free to seek a C3PAO certification assessment, but this would be unnecessary, because a valid DIBCAC High assessment with a 110 score will automatically be converted in SPRS to reflect a CMMC Final Level 2 certification assessment provided all requirements of §170.20(a)(1) are met. A DIBCAC High assessment conducted after the rule is effective is not eligible for standards acceptance. 26. CMMC Requirements and International Entities a. Applicability to International Entities Comment:

Nonrecurring and recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with CMMC Level 1 since it is assumed the contractor or subcontractor has already implemented the basic safeguarding requirements set forth in FAR 52.204-21, which are the CMMC Level 1 security requirements. Self-Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 1 assessment and affirmation is *\$5,977 (as summarized in Table 1) A Level I Self-Assessment is conducted annually, and is based on the assumptions detailed: Phase 1: Planning and preparing for the assessment: \$1,803 A director (MGMT5) for 4 hours (\$190.52/hr × 4hrs = \$762) An external service provider (ESP) for 4 hours (\$260.28 × 4hrs = \$1,041) Phase 2: Conducting the self-assessment: \$2,705 A director (MGMT5) for 6 hours (\$190.52/hr × 6hrs = \$1,143) An external service provider (ESP) for 6 hours (\$260.28 × 6hrs = \$1,562) Phase 3: Reporting of Assessment Results into SPRS: \$909 A director (MGMT5) for 2 hours (\$190.52/hr × 2hrs = \$381) An external service provider (ESP) for 2 hours (\$260.28/hr × 2hrs = \$521) A staff IT specialist (IT4-SB) for 0.08 hours [60] (\$86.24/hr × 0.08hrs = \$7) Affirmation: initial affirmation post assessment: \$560 Reaffirmations: It is estimated that the costs to reaffirm a CMMC Level I annually for a small entity is \$560 A director (MGMT5) for 2 hours (\$190.52/hr × 2hrs = \$381) A staff IT specialist (IT4-SB) for 2.08 hours (\$86.24/hr × 2.08hrs = \$179) The Level 1 Self-Assessment and Affirmations cost burden will be addressed as part of the 48 CFR acquisition rule.

Summary: The following is the annual small entities total cost summary for CMMC Level 1 self-assessments and affirmations over a ten-year period: (printed page 89108) (Example calculation, Year 1: *\$5,977 per entity × 699 entities (cumulative) = \$4,177,845). CMMC Level 2 Self-Assessment and Affirmation Costs for Small Business Entities The costs account for a CMMC Level 2 Self-Assessment of the applicable contractor information system(s) with NIST SP 800-171 Rev 2 requirements based on assumptions defined. Nonrecurring and recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with a CMMC Level 2 Self-Assessment since it is assumed the contractor or subcontractor has implemented the NIST SP 800-171 Rev 2 security requirements. Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 2 self-assessment and affirmation for a small entity is *\$34,277. The three-year cost is \$37,196 (as summarized in 4.1.2, Table 2), which includes the triennial assessment + affirmation, plus two additional annual affirmations (\$34,277 + \$1,459 + \$1,459). Phase 1: Planning and preparing for the self-assessment: \$14,426 A director (MGMT5) for 32 hours (\$190.52/hr × 32hrs = \$6,097) An external service provider (ESP) for 32 hours (\$260.28/hr × 32hrs = \$8,329) Phase 2: Conducting the self-assessment: \$15,542

The Crypto Publication Review Board identifies standards and guidelines to be reviewed in order to reaffirm, update, revise, convert, or withdraw the standard or guideline. 1 As explained in NIST IR 8319 [55], the review process presents an opportunity to retrospectively examine the development of the standard or guideline under review with a focus on the technical properties that are likely to be much better understood in the years since the standard or guideline was finalized. This report will mainly focus on the technical merits, although it is important to also provide editorial comments to determine whether the standards or guidelines are correct, complete, consistent, and unambiguous. NIST IR 8319 discussed the scope of a review, which needs to be broad enough to capture possible issues with the standard or guideline but narrow enough to provide concrete recommendations within a reasonable amount of time. More specifically, reviews focus on the resources available on the NIST website related to the standard or guideline combined with academic publications and other publicly available resources to understand the security properties of a cryptographic algorithm or implementation. By analyzing how the resources available on the NIST website related to the standard or guideline are organized, the implicit and explicit guarantees and assumptions between different standards and guidelines can become apparent. The instantiation of the block cipher modes of operation requires an approved block cipher, such as AES; therefore, the report of the block cipher modes of operation can be based on technical assumptions that were evaluated in NIST IR 8319. For example, NIST IR 8319 explored whether the AES block cipher behaves as a 'pseudo-random permutation' (PRP), so that the block cipher modes of operation can rely on this assumption.

(A) A requirement to prepare a TP will be included in each arrangement that involves the international transfer of classified material as freight. The TP will: (1) Describe requirements for the secure shipment of the material from the point of origin to the ultimate destination. (2) Provide for security requirements in the event the transfer cannot be made promptly. (B) The U.S. and recipient government DGRs will be identified in the TP as well as any requirement for an escort. When there are to be repetitive shipments, a notice of classified consignment will be used. (ii) Government agency arrangements. Classified material to be furnished to a foreign government under such transactions normally will be shipped via government agency-arranged transportation and be transferred to the foreign government's DGR within the recipient government's territory. (A) The government agency that executes the arrangement is responsible, in coordination with the recipient foreign government, for preparing a TP. (B) When the point of origin is a U.S. contractor facility, the GCA will provide the contractor with a copy of the TP and the applicable letter of offer and acceptance. If a freight forwarder will be involved in processing the shipment, the GCA will provide a copy of the TP to the freight forwarder. (C) Commercial arrangements. (1) The contractor will prepare a TP in coordination with the receiving government. This requirement applies whether the material is moved by land, sea, or air, and applies to U.S. and foreign classified contracts. (2) After the CSA approves the TP, the CSA will forward it to the recipient foreign government security authorities for final coordination and approval. The CSA will notify the contractor upon the concurrence by the respective parties. (D) International carriers. The international transfer of classified material will be made using only ships, aircraft, or other carriers that: (1) Are owned or chartered by the USG or under U.S. registry; (printed page 83351) (2) Are owned or chartered by or under the registry of the recipient government; or (3) Are other than those described that are expressly authorized to perform this function in writing by the Designated Security Authority of the GCA and the security

authorities of the foreign government involved. This authority cannot be delegated and this exception may be authorized only when a carrier described in paragraph (d)(2)(iv)(A) or (d)(2)(iv)(B) in this section is not available and an urgent operational requirement dictates use of the exception. (E) Escorts. (1) The contractor must provide escorts for international shipments of SECRET or CONFIDENTIAL material by air. (2) Escorts must have an eligibility determination and access to classified information at the classification level of the material being shipped. (3

CMMC Program rule is not an acquisition regulation, however, a CMMC Conditional Certification meets the CMMC program certification requirements. Any comments related to contract requirements should be directed to the related 48 CFR part 204 CMMC Acquisition rule. CMMC requirements apply to contracts that include FAR clause 52.204-21 or DFARS clause 252.204-7012 and result in processing, storing, or transmitting of FCI or CUI on a contractor owned information system. The CMMC program is not a verification program for compliance with all requirements of DFARS clause 252.204-7012, rather, its purpose is to ensure compliance with FAR clause 52.204-21, NIST SP 800-171 R2, and NIST 800-172 Feb2021 when applicable. The DoD does not provide detailed instruction on how to implement specific solutions to meet security requirements identified in the FAR clause or applicable NIST requirements, which is determined by the OSA. Any deviation from or change to the DFARS clause 252.204-7012 clause is beyond the scope of this rule. Each of the teams responsible for developing these two CMMC rules has reviewed both documents. There are no CMMC requirements for reviewing FCI or CUI solicitation material. Recommendations to adopt standard contracting procedures for award of DoD contracts (i.e., to exclude CUI information in the basic award) are out the scope of this 32 CFR part 170 CMMC Program rule. In support of the 32 CFR part 170 CMMC Program final rule, DoD issued policy guidance to its program managers and acquisition workforce to identify the appropriate CMMC requirement in solicitations and contracts. The CMMC assessment level required does not change based on acquisition lifecycle phase and is based on whether FCI and CUI are processed, stored, or transmitted on contractor owned information systems used in the performance of a contract. Discussion of DoD's willingness to provide advance notice of CMMC requirements or to remove the PM's discretion to include the CMMC level that best suits program requirements is a 48 CFR part 204 CMMC Acquisition rule matter and outside the scope of this rule. The CMMC Level will be identified in the solicitation. Once attained, a CMMC self-assessment or certification can be used in support of any number of proposals and solicitations. 5. Litigation and False Claims Comment:

As a result, while the technology may be new or developing, securing ePHI involved with the technology can be successfully executed through compliance with the Security Rule. Before implementing new and emerging technologies, a regulated entity must conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI. [878] It must then implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level. [879] Such administrative, physical, and technical safeguards apply to all instances of ePHI maintained or transmitted by the regulated entity, regardless of the technology used. Below, we discuss some examples of new technologies, such as quantum computing, AI, and virtual and augmented reality (VR and AR), and (printed page 989) how the Security Rule would apply in each case. 1. Quantum Computing Several Federal agencies have considered the potential benefits and drawbacks of quantum information science, [880] that is, the study of the impacts of quantum physics properties on information science. Those properties can increase computational power and speed significantly over classical computers, provide precision measurements; enhance sensing capabilities; and increase the accuracy of position, navigation, and timing services. [881] According to NIST, In recent years, there has been a substantial amount of research on quantum computers machines that exploit quantum mechanical phenomena to solve mathematical problems that are difficult or intractable for conventional computers. [882] However, the increase in computational capability threatens the security of asymmetric cryptography, [883] which is critical to encryption solutions, a key protection for ePHI and other sensitive information today. Scientists warn that when such quantum computers are built, they will have the ability to break many of the systems for asymmetric cryptography that are in use today. [884] Thus, experts anticipate that quantum computing will adversely affect the confidentiality and integrity of digital communications. [885] The goal of post-quantum cryptography (also called quantum-resistant cryptography) is to develop cryptographic systems that are secure against both quantum and classical computers, and can interoperate with existing communications protocols and networks. [886] A recent National Security Memorandum affirmed that alongside its potential benefits, quantum computing also poses

significant risks to the economic and national security of the United States. . . . [including the potential to break] much of the public-key cryptography used on digital systems across the United States and around the world. [887]

·To the Bureau of the Census to plan or carry out a census or survey, or related activity pursuant to Title 13 of the U.S. Code. (5) 5 U.S.C. 552a(b)(5) ·To a recipient who has provided DA or DOD with advance adequate written assurance that the record will be used solely as a statistical research or reporting record, and the record is to be transferred in a form that is not individually identifiable. (6) 5 U.S.C. 552a(b)(6) ·To the National Archives and Records Administration as a record that has sufficient historical or other value to warrant its continued preservation by the U.S. Government, or for evaluation by the Archivist of the United States or the designee of the Archivist to determine whether the record has such value. Note: Records transferred to the Federal Records Centers for storage remain under the control of the DA and no accounting for disclosure is required under the Privacy Act. (7) 5 U.S.C. 552a(b)(7) ·To another agency or instrumentality of any governmental jurisdiction within or under the control of the United States for a civil or criminal law enforcement activity, if the activity is authorized by law, and if the head of the agency or instrumentality has made a written request to the Army or the DOD specifying the particular portion desired and the law enforcement activity for which the record is sought. (8) 5 U.S.C. 552a(b)(8) ·To a person pursuant to a showing of compelling circumstances affecting the health or safety of an individual if upon such disclosure, notification is transmitted to the last known address of such individual. (9) 5 U.S.C. 552a(b)(9) ·To either House of Congress, or, to the extent the matter is within its jurisdiction, any committee or subcommittee thereof, or any joint committee of Congress or subcommittee of any such joint committee. Requests from a Congressional member acting on behalf of a constituent are not included in this exception, but may be covered by a routine use exception to the Privacy Act (See applicable Army system of records notice). (10) 5 U.S.C. 552a(b)(10) ·To the Comptroller General or authorized representatives, in the course of the performance of the duties of the Government Accountability Office. (11) 5 U.S.C. 552a(b)(11) ·Pursuant to the order of a court of competent jurisdiction. The order must be signed by a judge. (12) 5 U.S.C. 552a(b)(12) ·To a consumer reporting agency in accordance with section 3711(e) of Title 31 of the U.S. Code. The name, address, SSN, and other information identifying the individual; amount, status, and history of the claim; and the agency or program under which the case arose may be disclosed. However, before doing so, agencies must complete a series of steps designed to validate the debt and to offer the individual an opportunity to repay it. (d) DOD Blanket Routine Uses.

to the extent that the systems contain any information properly classified under Executive Order 13526 and that is required by that Executive Order to be kept secret in the interest of national defense or foreign policy. This exemption is applicable to parts of all systems of records including those not (printed page 24132) otherwise specifically designated for exemptions herein which contain isolated items of properly classified information. (c) Exemption for Anticipation of a Civil Action or Proceeding. All systems of records maintained by the NGB shall be exempt under section (d)(5) of 5 U.S.C. 552a , to the extent that the record is compiled in reasonable anticipation of a civil action or proceeding. (d) General Exemptions. No SOR within the NGB shall be considered exempt under subsection (j) or (k) of 5 U.S.C. 552a until the exemption rule for the SOR has been published as a final rule in the FR. (e) Specific exemptions. (1) System identifier and name: INGB 001, Freedom of Information Act (5 U.S.C.) and Privacy Act (5 U.S.C. 552a) Case Files. (i) Exemption: During the course of a 5 U.S.C. 552 or 5 U.S.C. 552a action, exempt materials from other systems of records may, in turn, become part of the case records in this system. To the extent that copies of exempt records from those other systems of records are entered into this 5 U.S.C. 552 or 5 U.S.C. 552a case record, the NGB hereby claims the same exemptions for the records from those other systems that are entered into this system, as claimed for the original primary SOR which they are a part. (ii) Authority: 5 U.S.C. 552a , sections (j)(2), (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons: Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this SOR. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal

employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (2) System identifier and name: INGB 005, Special Investigation Reports and Files. (i) Exemption: Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection

n binary analysis for supply chain security following NIST recommendations for using SBOM, and vulnerability disclosure reports were viewed by the panel as an excellent source of security information. This provided viewpoints related to a participant question in chat who asked, "Is the EO sufficient in imposing awareness/compliance obligations across the Supply Chain-producers, component producers, acquirers, users (government and industry)?"

3.1.1 Credential Theft or Compromise ... 3.1.1 Credential Theft or Compromise Credentials are used to verify the identity of users, authenticate them, and grant access to storage systems and tools.

This rule proposes standards for the security of individual health information and electronic signature use by health plans, health care clearinghouses, and health care providers. The health plans, health care clearinghouses, and health care providers would use the security standards to develop and maintain the security of all electronic individual health information. The electronic signature standard is applicable only with respect to use with the specific transactions defined in the Health Insurance Portability and Accountability Act of 1996, and when it has been determined that an electronic signature must be used. The use of these standards would improve the Medicare and Medicaid programs, and other Federal health programs and private health programs, and the effectiveness and efficiency of the health care industry in general. This rule would implement some of the requirements of the Administrative Simplification subtitle of the Health Insurance Portability and Accountability Act of 1996.

In summary, the CMMC Program enforces and validates implementation of DoD's required cyber protection standards for companies in the DIB, preserving U.S. technical advantage. In addition, CMMC increases security for the most sensitive CUI by applying additional requirements at Level 3. Implementation of CMMC will help protect FCI and CUI upon which DoD systems and critical infrastructure rely, making it vital to national security. CMMC is focused on securing the Department's supply chain, including the smallest, most vulnerable innovative companies. The security risks that result from the significant loss of FCI and CUI, including intellectual property and proprietary data, make implementation of the CMMC Program vital, practical, and in the public interest. III. Regulatory Compliance Analysis A. Executive Order 12866 , 'Regulatory Planning and Review' and Executive Order 13563 , 'Improving Regulation and Regulatory Review,' as Amended by Executive Order 14094 , 'Modernizing Regulatory Review' These Executive Orders direct agencies to assess all costs, benefits, and available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health, safety effects, distributive impacts, and equity). These Executive Orders emphasize the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. The Office of Management and Budget (OMB) has determined this final rule is significant as defined by Section 3(f)(1) for purposes of Executive Order 12866 , as amended by Executive Order 14094 . B. Congressional Review Act (5 U.S.C. 801 et seq.) As defined by 5 U.S.C. 804(2) , a major rule is a rule that the Administrator of the Office of Information and Regulatory Affairs of the Office of Management and Budget finds has resulted in or is likely to result in-(a) an annual effect on the economy of \$100,000,000 or more; (b) a major increase in costs or prices for consumers, individual industries, Federal, State, or local government agencies, or geographic regions; or (c) significant adverse effects on competition, employment, investment, productivity, innovation, or on the ability of United States-based enterprises to compete with foreign-based enterprises in domestic and export markets. This rule has been designated a major rule as it is expected to have annual effect on the economy of \$100M dollars or more. C. Public Law 96-354, 'Regulatory Flexibility Act' (5 U.S.C. 601) The Department of Defense Chief Information Officer certified that this rule is subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would, if promulgated, have a significant economic impact on a substantial number of small entities.

CMMC Acquisition final rule. Additionally, the information collection burden requirements for the CMMC instantiation of eMASS are addressed in a separate 32 CFR part 170 CMMC Program final rule information collection request (ICR). OSCs follow procedures as defined in § 170.17 to prepare for CMMC Level 2 certification assessment. Certified Assessors assigned by C3PAOs follow requirements and procedures as defined in § 170.17 to conduct CMMC assessments on defense contractor information systems to determine conformance with the information safeguarding requirements associated with CMMC Level 2. This is an assessment to validate implementation of the 110 security requirements from NIST SP 800-171 R2. Prospective C3PAOs must complete and submit the Standard Form (SF) 328 Certificate Pertaining to Foreign Interests (OMB control number 0704-0579) upon request from Defense Counterintelligence and Security Agency (DCSA). C3PAOs must generate and collect pre-assessment and planning material (contact information for the OSC, (printed page 83210) information about the C3PAO and assessors conducting the assessment, the level of assessment planned, the CMMC Model and Assessment Guide versions, and assessment approach), artifact information (list of artifacts, hash of artifacts, and hashing algorithm used), final assessment reports, appropriate CMMC certificates of assessment, and assessment appeal information. C3PAOs submit the data they generate and collect into the CMMC instantiation of eMASS, the information collection required for this submission is addressed in a separate CMMC eMASS ICR for the 32 CFR part 170 CMMC Program rule. OSCs may have a POA&M at CMMC Level 2 as addressed in § 170.21. C3PAOs perform a POA&M closeout assessment. The C3PAO process to conduct a POA&M Close-out Assessment, where applicable, is the same as the initial assessment with the same information collection requirements. OSCs must retain artifacts used as evidence for the assessment for the duration of the validity period of the certificate of assessment, and at minimum, for six years from the date of certification assessment as addressed in § 170.17(c)(4). The OSC is responsible for compiling relevant artifacts as evidence and having knowledgeable personnel available during the assessment. The organizational artifacts are proprietary to the OSC and will not be retained by the assessment team unless expressly permitted by the OSC. To preserve the integrity of the artifacts reviewed, the OSC creates a hash of assessment evidence (to include a list of the artifact names, the return values of the hashing algorithm, and the hashing algorithm used) and retains the artifact information for six years. The information obtained from the artifacts is an information collection and is provided to the C3PAO for uploading into the CMMC instantiation of eMASS (addressed in a separate CMMC eMASS ICR for the 32 CFR part 170

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The rapid development and wide application of distributed network systems have made network security - especially access control and data privacy - ever more important. Blockchain technology offers features such as decentralization, high confidence, and tamper-resistance, which are advantages to solving auditability, resource consumption, scalability, central authority, and trust issues - all of which are challenges for network access control by traditional mechanisms.

for CMMC Level 1, the security requirements set forth in FAR clause 52.204-21, and for CMMC Level 2, the security requirements set forth in NIST SP 800-171 R2. DoD did not consider the cost of implementing the security requirements themselves because implementation is already required by FAR clause 52.204-21, effective June 15, 2016, and by DFARS clause 252.204-7012, requiring implementation by Dec. 31, 2017, respectively; therefore, the costs of implementing the security requirements for CMMC Levels 1 and 2 should already have been incurred and are not attributed to this rule. As such, the nonrecurring engineering and recurring engineering costs to implement the security requirements defined for CMMC Level 1 and Level 2 are not included in this economic analysis. However, cost estimates to implement CMMC Level 3, are included, as that CMMC level will

require defense contractors and subcontractors, as applicable, to implement a DoD-defined subset of the security requirements set forth in NIST SP 800-172 Feb2021, a new addition to current security protection requirements. In estimating the public cost for a defense contractor small entity to comply with CMMC Program requirements for each CMMC level, DoD considered non-recurring engineering costs, recurring engineering costs, assessment costs, and affirmation costs for each CMMC Level. These costs include labor and consulting. Estimates include size and complexity assumptions to account for typical organizational differences between small entities and other than small entities with respect to the handling of Information Technology (IT) and cybersecurity: small entities are likely to have a less complex, less expansive operating environment and IT/Cybersecurity infrastructure compared to larger defense contractors small entities are likely to outsource IT and cybersecurity to an External Service Provider (ESP) entities (small and other than small) pursuing Level 2 self-assessment are likely to seek consulting or implementation assistance from an ESP to either help them prepare for the assessment technically or participate in the assessment with the C3PAOs. Estimates do not include the cost to implement (Non-recurring Engineering Costs (NRE)) or maintenance costs (Recurring Engineering (RE)) associated with the security requirements prescribed in current regulations.

- PRIORITY AREAS - - Cryptography 5 - Education & Workforce 7 - Emerging Technology 9 - HumanCentered Cybersecurity 11 - Identity & Access Management 13 - Privacy 15 - Risk Management 17 - Trusted Networks & Platforms 19 - National Cybersecurity Center of Excellence (NCCoE) 21 - Stakeholder Engagement & Events 24 ## Identity & Access Management ## IDENTITY & ACCESS MANAGEMENT

<!-- image --> ## NIST Internal Report NIST IR 8572 ## Workshop Summary Report for 'Workshop on Foundational Cybersecurity Activities for IoT Device Manufacturers ' Katerina N. Megas Michael Fagan Barbara Cuthill Brad Hoehn Evie Petrella This publication is available free of charge from: <https://doi.org/10.6028/NIST.IR.8572> <!-- image --> ## NIST Internal Report NIST IR 8572 ## Workshop Summary Report for 'Workshop on Foundational Cybersecurity Activities for IoT Device Manufacturers ' Katerina N. Megas Michael Fagan Barbara Cuthill Applied Cybersecurity Division Information Technology Laboratory Brad Hoehn HII Evelyn Petrella Electrosoft This publication is available free of charge from: <https://doi.org/10.6028/NIST.IR.8572> May 2025 <!-- image --> U.S. Department of Commerce Howard Lutnick, Secretary National Institute of Standards and Technology Craig Burkhardt, Acting Under Secretary of Commerce for Standards and Technology and Acting NIST Director Certain equipment, instruments, software, or materials, commercial or non-commercial, are identified in this paper in order to specify the experimental procedure adequately. Such identification does not imply recommendation or endorsement of any product or service by NIST, nor does it imply that the materials or equipment identified are necessarily the best available for the purpose. There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST.

Information such as the specific name of the food will allow FDA to limit its investigation to the implicated food. For example, if FDA has a reasonable belief that a shipment of cheddar cheese is contaminated, traceback or trace forward would be better facilitated if the records contained the identifier 'cheddar.' This would help FDA narrow its investigation and increase the speed of the trace. The information would also help the involved firm limit the scope of any recall, should it be necessary. However, FDA does recognize the diversity of the food chain and has allowed for flexibility in the final rule. For example, the requirement to record lot/code number or other identifier applies only to persons who manufacture, process, or pack food and only to the extent that information exists. Also, the final rule allows covered persons to use existing abbreviations or codes currently used to identify the food. However, if these abbreviations and/or codes are used, they must be readily deciphered for FDA upon request so that an 'adequate description' of the food is recorded. (Comment 88) One comment questions the need for the extensive recordkeeping requirements in the regulations and suggests that much of the facility information required in the recordkeeping rule is already required in the registration interim final rule. The comment gives as an example the duplicate requirements that the nontransporter must maintain a record of the

responsible individual, fax number, and e-mail address for: (1) The facility that shipped product to your facility, (2) the transportation company that delivered the product, (3) the transportation company that picked up product from your facility, and (4) the facility where your product is being shipped.

SI.L2-3.14.4 · Update Malicious Code Protection [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13 255 Traditional malicious code protection mechanisms cannot always detect such code. In these situations, organizations rely instead on other safeguards including secure coding practices, configuration management and control, trusted procurement processes, and monitoring technologies to help ensure that software does not perform functions other than the functions intended. FURTHER DISCUSSION Malware changes on an hourly or daily basis, and it is important to update detection and protection mechanisms frequently to maintain the effectiveness of the protection. Example You have installed anti-malware software to protect a computer from malicious code. Knowing that malware evolves rapidly, you configure the software to automatically check for malware definition updates every day and update as needed [a]. Potential Assessment Considerations · Is there a defined frequency by which malicious code protection mechanisms must be updated (e.g., frequency of automatic updates or manual processes) [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.14.4 · FAR Clause 52.204-21 b.1.xiv

CIS Safeguard 2.1 · Establish and Maintain a Software Inventory Establish and maintain a detailed inventory of all licensed software installed on enterprise assets. The software inventory must document the title, publisher, initial install/use date, and business purpose for each entry; where appropriate, include the Uniform Resource Locator (URL), app store(s), version(s), deployment mechanism, and decommission date. Review and update the software inventory bi-annually, or more frequently. Implementation Groups: 1,2,3 Asset Type: applications Security Function: identify Parent Control: Inventory and Control of Software Assets

Direct search and duplication cost for any record not described in this paragraph shall be computed in the manner described for audiovisual documentary material. (g) Costs for special services. Complying with requests for special services is at the discretion of the Components. Neither the FOIA nor its fee structure covers these kinds of services. Therefore, Components may recover the costs of special services requested by the requester after agreement has been obtained in writing from the requester to pay for one or more of the following services: (1) Certifying that records are true copies. (2) Sending records by special methods such as express mail, etc. § 286.26 Fees for technical data. (a) Technical data is recorded information related to experimental, developmental, or engineering works that can be used to define an engineering or manufacturing process or to design, procure, produce, support, maintain, operate, repair, or overhaul material. The data may be graphic or pictorial delineations in media, such as drawings or photographs, text in specification or related performance or design type documents, or computer printouts. Examples of tech data include research and engineering data, engineering drawings, and associated lists, specifications, standards, process sheets, manuals, technical reports, catalog item identification, and related information and computer software documentation. (b) Unless technical data qualifies for withholding from public release under one or more of the FOIA exemptions, it shall be released to the requester after all reasonable costs attributed to search, duplication, and review are paid as authorized by 10 U.S.C. 2328 . All reasonable costs are the full costs to the Federal Government for rendering the service, or fair market value of the service, whichever is higher. Fair market value shall be determined in accordance with commercial rates in the local geographic area. In the absence of a known market value, charges will be based on recovery of all direct and indirect costs to conduct the search, review, and duplicate the documents. This cost is to be differentiated from the direct costs allowable under § 286.24 for other types of information released under the FOIA. (1) The DoD Components shall retain the amounts received by such a release, and it shall be merged with and available for the same purpose and the same time period as the appropriation from which the costs were incurred in complying with request. (2) The DoD Components that process FOIA requests for technical data and are eligible to recoup the direct costs for providing the records shall establish an appropriate fee schedule taking into account the prevailing commercial rates. (c) Waiver. The DoD Components shall waive the payment of costs required in § 286.24(a) which are greater than the costs that would be required for release of this same information under § 186.25(a) of this subchapter if:

(iii) The manufacturer name, make, model number, model year, and serial number for all aircraft

under FSCs 1510 and 1520. (iv) Appropriate Federal Condition Codes. See Appendix 2 of DoD 4000.25-2, Military Standard Transaction Reporting and Accounting Procedures manual, edition in effect as of the date of this contract. Information on Federal Condition Codes can be obtained at http://www.DLA.Mil/J-6/DLMSO/Elibrary/Manuals/Milstrap/AP2_Index.asp. (2) If the schedules are acceptable, the plant clearance officer shall complete and send the Contractor a DD Form 1637, Notice of Acceptance of Inventory. (c) Proceeds from sales of surplus property. Unless otherwise provided in the contract, the proceeds of any sale, purchase, or retention shall be: (1) Forwarded to the Contracting Officer; (2) Credited to the Government as part of the settlement agreement; (3) Credited to the price or cost of the contract; or (4) Applied as otherwise directed by the Contracting Officer. (d) Demilitarization, mutilation, and destruction. If demilitarization, mutilation, or destruction of contractor inventory is required, the Contractor shall demilitarize, mutilate, or destroy contractor inventory, in accordance with the terms and conditions of the contract and consistent with Defense Demilitarization Manual, DoDM 4160.28-M, edition in effect as of the date of this contract. The plant clearance officer may authorize the purchaser to demilitarize, mutilate, or destroy as a condition of sale provided the property is not inherently dangerous to public health and safety. (e) Classified Contractor inventory. The Contractor shall dispose of classified contractor inventory in accordance with applicable security guides and regulations or as directed by the Contracting Officer. (f) Inherently dangerous Contractor inventory. Contractor inventory dangerous to public health or safety shall not be disposed of unless rendered innocuous or until adequate safeguards are provided. (g) Contractor inventory located in foreign countries. Consistent with contract terms and conditions, property disposition shall be in accordance with foreign and U.S. laws and regulations, including laws and regulations involving export controls, host nation requirements, Final Governing Standards, and Government-to-Government agreements. The Contractor's responsibility to comply with all applicable laws and regulations regarding export-controlled items exists independent of, and is not established or limited by, the information provided by this clause. (h) Disposal of scrap. (1) Contractor with scrap procedures.

Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food are subject to §§ 1.361 and 1.363 with respect to its packaging (the outer packaging of food that bears the label and does not contact the food). All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import packaging are excluded from all of the requirements of subpart J of this final rule. Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food contact substances other than the finished container that directly contacts the food are excluded from all of the requirements of subpart J, except §§ 1.361 and 1.363. Persons who place food directly in contact with its finished container are subject to all of the requirements of subpart J of this final rule as to the finished container that directly contacts that food. All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that directly contacts the food are excluded from the requirements of subpart J as to the finished container, except §§ 1.361 and 1.363. Persons who receive or hold food on behalf of specific individual consumers and who are not also parties to the transaction and who are not in the business of distributing food are excluded from all of the requirements of subpart J. Transporters can meet their obligation to establish and maintain records in the following ways: (1) Keeping the records listed in § 1.352(a); (2) keeping the records listed in § 1.352(b), which contain information also currently required of roadway interstate transporters under the FMCSA regulations as of the date of publication of this final rule; (3) keeping the records listed in § 1.352(c), which contain information also currently required of rail and water interstate transporters under the STB regulations as of the date of publication of this final rule; (4) keeping the records listed in § 1.352(d), which contain information also currently required of international air transporters on air waybills under the Warsaw Convention; or (5) entering into an agreement with a nontransporter immediate previous source in the United States or a nontransporter immediate subsequent recipient in the United States to keep records for them. The agreement must contain certain elements specified in § 1.352(c). Intrastate transporters must also establish and maintain records under this final rule and can meet this obligation by complying with either § 1.352(a), (b), (c), (d), or (e). Foreign persons who transport food in the United States, whether or not (printed page 71565) they have possession, custody, or control of the food for the sole purpose of transporting, must comply with § 1.352 of subpart J of this final rule. The exclusion for pet food not subject to the recordkeeping provisions of the animal proteins prohibited in ruminant feed regulation (BSE rule) (62 FR 30935, June 5, 1997) has been deleted.

From the NIST SP 800-172 Rev 3 Final Public Draft: Monitoring for unauthorized or misconfigured components may be accomplished on an ongoing basis or by the periodic scanning of systems for that purpose. Automated mechanisms may also be used to prevent the connection of unauthorized or misconfigured system components. Automated mechanisms can be implemented in systems or in separate system components. When acquiring and implementing automated mechanisms, organizations consider whether such mechanisms depend on the ability of the system component to support an agent or supplicant in order to be detected since some types of components do not have or cannot support agents (e.g., IoT devices, sensors). Isolation can be achieved, for example, by placing unauthorized system components in separate domains or subnets or quarantining suc

IMPLEMENTING AND TESTING THE DISASTER RECOVERY PLAN | 88 || INFORMATION RISK ASSESSMENT AND SECURITY MANAGEMENT - CSMN 655 | 82 || INFORMATION POLICY - CS 230 | 63 || INFORMATION SECURITY PRINCIPLES AND PRACTICES | 17 |

(a) whether the proposed collections of information are necessary for the proper performance of the functions of DoD, including whether the information will have practical utility; (b) the accuracy of the estimate of the burden for both information collections; (c) ways to enhance the quality, utility, and clarity of the information to be collected; and (d) ways to minimize the burden on respondents, including the use of automated collection techniques or other forms of information technology. Specific information on both collections is below. DoD's Defense Industrial Base (DIB) Cybersecurity (CS) Activities Cyber Incident Reporting-OMB Control Number 0704-0489 Title: DoD's Defense Industrial Base (DIB) Cybersecurity (CS) Activities Cyber Incident Reporting. Type of Request: Revision. Number of Participants: Number of DoD contractors eligible to participate in the voluntary program is 80,000. DoD estimates that approximately 1% of the newly eligible population will elect to join the program each year with program growth plateauing at approximately 10% of the population by Year 9. Based on this estimate, after the first three years of the program expansion, 2,400 defense contractors will join the existing 980 participating companies resulting in 3,380 defense contractors submitting voluntary cyber threat information reports. Projected Responses per Participant: Five reports per participant. Annual Total Responses: 16,900. Average Burden per Response: Two hours. (printed page 27837) Annual Total Burden Hours: 33,800 hours for all voluntary submissions. Needs and Uses: DoD designated DC3 as the single focal point for receiving all cyber incident reporting affecting the unclassified networks of DoD contractors from industry and other government agencies. DoD collects cyber incident and threat reports using the Defense Industrial Base Network (DIBNet) portal (<https://dibnet.dod.mil>). Cyber threat reports are analyzed by experts at DC3 and they, in turn, develop written products that include analysis of the threat, mitigations, and indicators of adversary activity. These anonymized products are shared with authorized DoD personnel, authorized personnel from other Federal agencies, and authorized POCs from the DIB CS Program. Affected Public: Business or other for-profit and not-for-profit institutions. Frequency: On occasion. Respondent's Obligation: Voluntary. DoD's Defense Industrial Base (DIB) Cybersecurity (CS) Points of Contact (POC) Information-OMB Control Number 0704-0490 Title: DoD's Defense Industrial Base (DIB) Cybersecurity (CS) Activities Points of Contact (POC) Information. Type of Request: Revision. Number of Participants:

(Response) FDA acknowledges considerable uncertainty in the estimates of the numbers of mixed-type facilities that engage in farming and is receptive to comments from industry that can improve them. There is likely to be more uncertainty in the estimates of the number of mixed-type facilities that engage in any individual category of nut farming than that for the estimate of the number of mixed-type facilities that engage in nut farming over all categories of nuts. FDA will use the estimate provided by the comment to revise its estimate of mixed-type facilities that engage in nut farming from 2 percent to 6 percent. The total number of mixed type facilities that engage in farming is revised upward to 31,077 from 30,497 used in the PRIA. Table 13 of this document is a revised table of mixed-type facilities that engage in farming. Table 13. Mixed-Type Facilities Engage in Farming

Commodity	Total No. of Farms	Percent Mixed-Type	No. of Mixed-Type Farms
Pig farms (feed mixing)	46,353	1.5%	695
Cattle (feed mixing)	785,672	1.0%	7,857
Poultry (feed mixing)	36,944	1.0%	369
Other animal production (feed mixing)	110,580	1.0%	1,106
Dairy	86,022	1.1%	903
Grain, rice, and beans	462,877	1.0%	4,629
Apples	10,872	1.5%	163
Oranges	9,321	1.5%	140
Peaches	14,459	1.5%	217
Cherries	8,423	1.5%	126
Pears	8,062	1.5%	121
Other fruit	29,413	1.5%	441
Nuts	14,500	6.0%	870
Berries	6,807	1.5%	102
Grapes	11,043	10.5%	1,160
Olives	1,363	3.5%	48
Vegetables and melons	31,030	0.5%	155
Organic vegetables	6,206	50.0%	3,103
Honey	7,688	50.0%	3,844
Syrup	4,850	100.0%	4,850
Herbs	1,776	10.0%	

178 Total 31,077 (Comment 185) One comment states that FDA mistakenly omitted the number of food grade warehouses that are subject to the regulation included in NAICS code 49311. Consequently, FDA's estimate that a total of 76,952 wholesaler and public warehouse companies are affected by the regulation is too low, and these additional warehouses should be included in the cost calculation of the final rule. (Response) FDA agrees that public warehouses included in NAICS code number 49311 were omitted from the count of total warehouse facilities. Table 14 of this document describes the primary activities performed by the warehouses included in this classification. Table 14. Description of Primary Activities Performed by Warehouses by NAICS Code NAICS SIC Corresponding Index Entries 493110 4225 Bonded warehousing, general merchandise 493110 4225 General warehousing and storage 493110 AUX Private warehousing and storage, general merchandise 493110 4225 Public warehousing and storage (except self storage), general merchandise 493110 4226 Warehousing (including foreign trade zones), general merchandise 493110 4225 Warehousing and storage, general merchandise

Workstations are essential for workforce members to perform their assigned functions, such as clinicians entering an individual's health history and treatment plan or billing staff preparing claims. Workstations are one of the key entry points for users to access a regulated entity's information systems. Thus, the Security Rule contains provisions requiring that regulated entities secure not only their information systems, but also individual workstations. [405] However, as discussed above, the health care environment has changed. It now includes both the physical and virtual environment and is replete with mobile devices and other types of devices that may serve as multi-functional workstations. Clinicians and other workforce members often rely on smart phones, smart watches, tablets, laptops, and even personal digital assistants, among other devices. These devices have proliferated, and so has their ability to perform a wide variety of functions with increasing sophistication. The Department believes that it is necessary to update the definition to reflect the evolved nature of the landscape. b. Proposal In recognition of this changed environment, the Department proposes to modify the definition of workstation to provide additional examples of what constitutes a workstation. Specifically, we propose to add the examples of a server, virtual device, and a mobile device such as a smart phone or tablet. Virtual devices could include a virtual medical device, virtual server, or virtual desktop computer. The proposed definition also would clarify that technology properly considered as a ·workstation· is not limited to the proposed regulatory examples. 23. Request for Comment The Department requests comment on all the foregoing proposed definitions, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular: a. Whether any of the proposed definitions would be problematic for regulated entities or result in unintended adverse consequences. If so, please explain. b. Whether the Department should consider an alternative definition for any terms the Department proposes to define in the rule. If the answer is yes, please propose such an alternative definition and a reference or supporting rationale. c. Whether the Department should define any additional terms within the rule. If the answer is yes, please propose such additional terms and definitions, along with any reference or supporting rationale. d. With respect to the definitions of ·information system· and ·electronic information system·, the extent of a covered entity's direct management control over applications in cloud computing environments, such as a cloud-based EHR system.

termination for cause, reduction in force, involuntary transfer, criminal or disciplinary actions)? Is there a standard checklist for all action items that should be completed when a workforce member leaves (e.g., return of all access devices, deactivation of accounts, and delivery of any needed data solely under the workforce member's control)? Do other organizations need to be notified to deactivate accounts to which that the workforce member had access in the performance of their employment duties? However, regulated entities often do not establish or implement written procedures, nor, even in instances where they have established or implemented them, have they done so in an appropriate fashion to protect ePHI from improper access by current or former workforce members. Consistent with the guidance described above and other proposals in this NPRM, the Department proposes to redesignate the workforce security standard at 45 CFR 164.308(a)(3)(i) as proposed 45 CFR 164.308(a)(9)(i) , to add a paragraph heading to clarify the organization of the regulatory text, and to modify the regulatory text clarify that a regulated entity must implement written policies and procedures ensuring that workforce members have appropriate access to ePHI and to relevant electronic information systems. The regulated entity must also implement written policies and procedures preventing workforce members from accessing ePHI and relevant electronic information systems if they are not authorized to do so. The modifications we propose to the

implementation specification for authorization and/or supervision would clarify that a regulated entity is required to establish and implement written procedures for the authorization and/or supervision of workforce members who access ePHI or relevant electronic information systems or who work in facilities where ePHI or relevant electronic information systems might be accessed. [562] We propose similar modifications to the implementation specification for workforce clearance procedure, which would require a regulated entity to establish and implement written procedures to determine that the access of a workforce member to ePHI or relevant electronic information systems is appropriate, in accordance with written policies and procedures for granting and revising access to ePHI and relevant electronic information systems as required by proposed 45 CFR 164.308(a)(10)(ii)(B) . [563] Additionally, we propose several clarifications to the implementation specification for termination procedures. Specifically, the proposed implementation specification for modification and termination procedures at proposed 45 CFR 164.308(a)(9)(ii)(C) would require procedures for terminating a workforce member's access to ePHI and relevant electronic information systems, and to facilities where ePHI or relevant electronic information systems might be accessed. Proposed paragraph (a)(9)(ii)(C)(1

From the NIST SP 800-172 Rev 3 Final Public Draft: DISCUSSION 1167 Identity providers (both internal and external to the organization) manage user, 1168 device, and non-person entity authenticators and issue statements (often called identity assertions) that attest to the identities of other systems or system components. Authorization servers create and issue access tokens to identified and authenticated users and devices that can be used to gain access to organizational systems or information resources. For example, single sign-on (SSO) provides identity provider and authorization server functions. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude

) To the extent that a covered entity or business associate is implementing compensating controls under this paragraph (f)(2)(iv)(B), the effectiveness of compensating controls must be reviewed and documented by the designated Security Official at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, to continue securing electronic protected health information and its relevant electronic information systems. (v) Maintenance. Review and test the effectiveness of the technical controls required by this paragraph (f) at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. (g) Standard: Transmission security. Deploy technical controls to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network; and review and test the effectiveness of such technical controls at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. (h) Standard: Vulnerability management .(1) General. Deploy technical controls in accordance with the covered entity's or business associate's patch management policies and procedures required by §.164.308(a)(4)(ii)(A) to identify and address technical vulnerabilities in the covered entity's or business associate's relevant electronic information systems. (2) Implementation specifications .(i) Vulnerability scanning. (A) Conduct automated vulnerability scans to identify technical vulnerabilities in the covered entity's or business associate's relevant electronic information systems in accordance with the covered entity's or business associate's risk analysis required by §.164.308(a)(2) or at least once every six months, whichever is more frequent. (B) Review and test the effectiveness of the technology asset(s) that conducts the automated vulnerability scans required by paragraph (h)(2)(i)(A) of this section at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. (ii) Monitoring. Monitor authoritative sources for known vulnerabilities on an ongoing basis and remediate such vulnerabilities in accordance with the covered entity's or business associate's patch management program under §.164.308(a)(4). (iii) Penetration testing. Perform penetration testing of the covered entity's or business associate's relevant electronic information systems by a qualified person. (A) A qualified person is a person with appropriate knowledge of and experience with generally accepted cybersecurity principles and methods for ensuring the confidentiality, integrity, and availability of electronic protected health information.

(C) A communication plan, to include a description of how relevant threat information will be shared between PSC personnel and U.S. military forces and how appropriate assistance will be provided to

PSC personnel who become engaged in hostile situations. DoD contractors performing private security functions are only to be used in accordance with DoD Instruction 1100.22, "Guidance for Determining Workforce Mix," [12] that is, they are limited to a defensive response to hostile acts or demonstrated hostile intent. (D) Documentation of individual training covering weapons familiarization and qualification, rules for the use of force, limits on the use of force including whether defense of others is consistent with host nation Status of Forces Agreements or local law, the distinction between the rules of engagement applicable to military forces and the prescribed rules for the use of force that control the use of weapons by civilians, and the Law of Armed Conflict. (E) Written acknowledgment by the PSC and its individual PSC personnel, after investigation of background of PSC personnel by the contractor, verifying such personnel are not prohibited under U.S. law to possess firearms. (F) Written acknowledgment by the PSC and individual PSC personnel that: (1) Inappropriate use of force by contractor personnel authorized to accompany the U.S. Armed Forces may subject such personnel to United States (printed page 49658) or host nation prosecution and civil liability. [13] (2) Proof of authorization to be armed must be carried by each PSC personnel. (3) PSC personnel may possess only U.S.G.-issued and/or -approved weapons and ammunition for which they have been qualified according to paragraph (a)(1)(iii)(E) of this section. (4) PSC personnel were briefed about and understand limitations on the use of force. (5) Authorization to possess weapons and ammunition may be revoked for non-compliance with established rules for the use of force. (6) PSC personnel are prohibited from consuming alcoholic beverages or being under the influence of alcohol while armed. (iv) Registration and identification in the Synchronized Predeployment and Operational Tracker (or its successor database) of armored vehicles, helicopters, and other vehicles operated by PSC personnel. (v) Reporting alleged criminal activity or other incidents involving PSCs or PSC personnel by another company or any other person. All incidents involving the following shall be reported and documented: (A) A weapon is discharged by an individual performing private security functions; (B) An individual performing private security functions is killed or injured in the performance of their duties; (C) A person other than an individual performing private security functions is killed or injured as a result of conduct by PSC personnel; (D) Property is destroyed as a result of conduct by a PSC or PSC personnel;

AU.L2-3.3.2 · User Accountability CMMC Assessment Guide · Level 2 | Version 2.13 76 FURTHER DISCUSSION Capturing the necessary information in audit logs ensures that you can trace actions to a specific user. This may include capturing user IDs, source and destination addresses, and time stamps. Logging from networks, servers, clients, and applications should be considered in ensuring accountability. This requirement, AU.L2-3.3.2, which ensures logging and traceability of user actions, supports the control of non-privileged users required by AC.L2-3.1.7 as well as many other auditing, configuration management, incident response, and situation awareness requirements. Example You manage systems for a company that stores, processes, and transmits CUI. You want to ensure that you can trace all remote access sessions to a specific user. You configure the VPN device to capture the following information for all remote access connections : source and destination IP address, user ID, machine name, time stamp, and user actions during the remote session [b]. Potential Assessment Considerations · Are users uniquely traced and held responsible for unauthorized actions [a]? · Does the system protect against an individual denying having performed an action (non- repudiation) [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.3.2

The discussion below includes an Executive Summary, a description of relevant statutory and regulatory authority and history, the justification for this proposed regulation, a section-by-section description of the proposed modifications, and a regulatory impact analysis and other required regulatory analyses. The Department solicits public comment on all aspects of the proposed rule. The Department requests that persons commenting on the provisions of the proposed rule label their discussion of any particular provision or topic with a citation to the section of the proposed rule being addressed and identify the particular request for comment being addressed, if applicable. Table of Contents I. Executive Summary A. Overview B. Applicability C. Table of Abbreviations/Commonly Used Acronyms in This Document II. Statutory Authority and Regulatory History A. Statutory Authority and History 1. Health Insurance Portability and Accountability Act of 1996 (HIPAA) 2. Health Information Technology for Economic and Clinical Health (HITECH) Act B. Regulatory History 1. 1998 Security Rule Notice of Proposed Rulemaking 2. 2003 Final Rule 3. 2009 Delegation of Authority 4. 2013 Omnibus Rulemaking III. Justification for This Proposed Rulemaking A. Strong Security Standards Are Essential to Protecting the Confidentiality, Integrity, and Availability of ePHI and Ensuring Quality and Efficiency in the Health Care System B. The Health

opportunities to help me in my security awareness role. Strongly disagree - Disagree - Neither Agree nor Disagree - Agree - Strongly Agree ## Final Thoughts In this last section, we'll give you the opportunity to share your own lessons learned and any other information you think would be useful for us to know. 50. What are the most important pieces of advice or lessons learned you might pass on to someone just starting a security awareness program in an organization like yours? <openended text box>; 51. What could help your organization's security awareness program be more successful? <open-ended text box>; 52. Please describe anything else related to your organization's experiences or challenges with security awareness that you'd like us to know. <open-ended text box>;

| Operational Audits of Automated Information Systems (AISs) | Operational Audits of Automated Information Systems (AISs) | Operational Audits of Automated Information Systems (AISs) | 4 || | 1.1.5 | Relevant Laws and Regulations | Relevant Laws and Regulations | 4 || | 1.1.5.1 | Requirements for Audit Involvement | Requirements for Audit Involvement | 4 || | 1.1.5.2 | Requirements for Internal Control | 5 || | 1.2 | RISKS GENERATED BY COMPUTER TECHNOLOGY | RISKS GENERATED BY COMPUTER TECHNOLOGY | RISKS GENERATED BY COMPUTER TECHNOLOGY | 6 || | 1.2.1 Overview of Risks | 1.2.1 Overview of Risks | 1.2.1 Overview of Risks | 6 || | 1.2.1.1 | Definitions | 7 || | 1.2.1.2 | Vulnerability/Risk Related Requirements | 7 || | 1.2.2 | Risks in a Computerized Environment | Risks in a Computerized Environment | 8 || | 1.2.2.1 | Additional Risks Present in a Computerized Environment | 8 || | 1.2.2.2 | Assessing Vulnerabilities Through the Audit Process | 9 || | 1.3 | CONTROL OBJECTIVES AND STANDARDS IN A COMPUTER ENVIRONMENT | CONTROL OBJECTIVES AND STANDARDS IN A COMPUTER ENVIRONMENT

FAR 52.204-21 (Basic Safeguarding of Covered Contractor Information Systems) establishes 15 basic safeguarding requirements that all federal contractors must implement when handling Federal Contract Information (FCI). These 15 requirements form the basis of CMMC Level 1. The 15 requirements cover: 1. Limit system access to authorized users 2. Limit system access to authorized functions 3. Verify and control connections to external systems 4. Control information posted on public systems 5. Identify, report, and correct information flaws 6. Provide protection from malicious code 7. Update malicious code protection mechanisms 8. Perform periodic scans and real-time scans 9. Physical access protections 10. Escort visitors and monitor visitor activity 11. Sanitize or destroy information system media 12. Limit physical access to information systems 13. Authenticate identity before system access 14. Monitor, control, and protect communications 15. Control use of removable media and portable devices FAR 52.204-21 requirements are much less comprehensive than NIST SP 800-171 (110 requirements for CUI).

DCMA DIBCAC must generate and collect pre-assessment and planning material (contact information for the OSC, information about the assessors conducting the assessment, the level of assessment planned, the CMMC Model and Assessment Guide versions, and assessment approach), artifact information (list of artifacts, hash of artifacts, and hashing algorithm used), final assessment reports, appropriate CMMC certificates of assessment, and assessment appeal information. DCMA DIBCAC submits the data it generates and collects into the CMMC instantiation of eMASS (addressed in a separate CMMC eMASS ICR for the 32 CFR part 170 CMMC Program final rule). OSCs may have a POA&M at CMMC Level 3 as addressed in § 170.21. DCMA DIBCAC performs a POA&M closeout assessment. The DCMA DIBCAC process to conduct a POA&M close-out assessment, where applicable, is the same as the initial assessment with the same information collection requirements. OSCs must retain artifacts used as evidence for the assessment for the duration of the validity period of the certificate of assessment, and at minimum, for six years from the date of certification assessment as addressed in § 170.18(c)(4). The OSC is responsible for compiling relevant artifacts as evidence and having knowledgeable personnel available during the assessment. Assessors will not permanently retain assessment artifacts. To preserve the integrity of the artifacts reviewed during the assessment, the OSC creates a hash of assessment evidence (to include a list of the artifact names, the return values of the hashing algorithm, and the hashing algorithm used) and retains the artifact information for six years. The information obtained from the artifacts is an information collection and DCMA DIBCAC uploads the information into the CMMC instantiation of eMASS; the artifacts themselves are not an information collection. The OSC process to support a POA&M close-out assessment, where applicable, is the same as the initial assessment with the same information collection requirements. If an OSC does not agree with the assessment results, it may formally dispute the assessment and initiate an Assessment Appeal process with DCMA DIBCAC. DCMA DIBCAC submits assessment appeals using eMASS. Appeals are tracked in the CMMC instantiation of eMASS and any resulting changes to the assessment (printed

page 83211) results are uploaded into CMMC eMASS. DCMA DIBCAC maintains records for a period of six years of monitoring, education, training, technical knowledge, skills, experience, and authorization of each member of its personnel involved in inspection activities and working papers generated from Level 3 Certification Assessments. Use of Information Technology CMMC assessment data and results are collected using information technology. C3PAOs and DCMA DIBCAC electronically upload assessment data and results into the CMMC instantiation of eMASS (addressed in a separate CMMC eMASS ICR for the 32 CFR part 170

We considered not proposing revisions to the Security Rule. However, the Department believes that not revising the Security Rule would result in continued increases in both the number and size of breaches. Such increases would result in an exponential increase in costs as shown in table 8 above. If the modifications to the Security Rule result in even modest improvements to the security of ePHI, the reduction in the number and/or size of breaches would reduce the overall costs associated with breaches, including the costs of mitigating harm resulting from such breaches. Email Security The Department considered proposing a separate standard for regulated entities to secure email transmissions. In the Department's Cybersecurity Performance Goals, [986] the Department identifies email security as an essential goal for reducing risk from common email-based threats such as email spoofing, phishing, and fraud. Therein, the Department points to basic email protection controls identified in the Health Industry Cybersecurity Practices, such as spam/virus checking and real-time deny lists, as well as strategies that may be deployed across small, medium, and large organizations, including MFA for email access, email encryption, workforce education, and advance tooling (e.g., URL click protection via analytics, attachment sandboxing). [987] The Department is aware of the threat that email poses to the information systems of regulated entities and to the confidentiality, integrity, and availability of ePHI. [988] However, the Department believes that it is important that the Security Rule remain technology-neutral and that the security measures we propose in this NPRM apply to a regulated entity's information systems broadly, including email programs. For example, in this NPRM, the Department proposes to require regulated entities to encrypt all ePHI at rest and in transit and proposes a transmission security standard in which regulated entities would be required to deploy technical controls to guard against unauthorized access to ePHI that is being transmitted over an electronic communications network. [989] Therefore, the Department believes it is unnecessary to promulgate a separate standard for email security. Because the other technical controls, such as encryption and MFA, are already incorporated into the requirements that would protect relevant electronic information systems, the Department believes that adopting a separate secure email standard would duplicate costs without creating a net benefit. (printed page 1005) Additionally, the Department considered whether to heighten the existing expectation [990] for regulated entities to inform individuals before transmitting ePHI to the individual via unencrypted email in response to a request for access under 45 CFR 164.524 by this means. We considered whether to require such notification for different types of requests, such as different categories of PHI (e.g.,

FDA received a number of comments regarding using the definition of 'food' in section 201(f) of the FD&C Act, which includes food contact substances within its scope. These comments are addressed in section III.D.10, entitled 'Food Contact Materials.' For the reasons stated therein, FDA has decided to retain the definition of food as proposed; however, the final rule exempts persons who manufacture, pack, transport, distribute, receive, hold, or import food contact substances, other than the finished container that directly contacts the food, from all requirements of subpart J of this final rule, except §§ 1.361 and 1.363. Further, persons who place food directly in contact with its finished container are subject to all of the requirements of subpart J as to the finished container that directly contacts that food. All other persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that directly contacts the food are excluded from the requirements of subpart J as to the finished container, except §§ 1.361 and 1.363 (regarding access to existing records). 6. Foreign Facility (Comment 69) One comment asks whether 'foreign facility' includes warehouses in ports belonging to shipping companies, land transport or air lines, sealed container deposits, public organization facilities of the foreign government and of other federal agency representatives (such as FDA or USDA) in the country of origin and/or shipment. Another comment states that FDA's definition of foreign facility is too inclusive. The comments suggest that only foreign manufacturers and exporters should be required to keep records of their partners, such as packing facilities and holding facilities. (Response) FDA has deleted the definition of foreign facility in the final rule. FDA notes that foreign persons, except foreign persons who transport food in the United States, are excluded from all of these

regulations in subpart J of this final rule. 7. Manufacturing/Processing There were no comments on this issue. 8. Nontransporter

Protecting CUI in Nonfederal Systems and Organizations. Contractors are also required to flow down DFARS clause 252.204-7012 to all subcontracts for operationally critical support or for which subcontractor performance will involve covered defense information. However, neither FAR clause 52.204-21 nor DFARS clause 252.204-7012 provide for DoD assessment of a contractor's implementation of the information protection requirements required by those clauses. The Department developed the CMMC Program to verify implementation of cybersecurity requirements in DoD contracts and subcontracts, by assessing adequacy of contractor information system security compliance prior to award and during performance of the contract. With limited exceptions, the Department intends to require compliance with CMMC as a condition of contract award. Once CMMC is implemented, the required CMMC Status will be specified in the solicitation and resulting contract. Contractors handling FCI or CUI will be required to meet the CMMC Status specified in the contract. There are three different levels of CMMC assessment, starting with basic safeguarding of FCI at Level 1, moving to the broad protection of CUI at Level 2, and culminating with higher level protection of CUI against risk from Advanced Persistent Threats (APTs) at Level 3. The benefits and costs associated with implementing this final rule, as well as alternative approaches considered, are as follows: Costs A Regulatory Impact Analysis (RIA) that includes a detailed discussion and explanation about the assumptions and methodology used to estimate the cost of this regulatory action follows and is available at www.regulations.gov (search for 'DoD-2023-OS-0063,' click 'Open Docket,' and view 'Supporting Documents'). Background The Department of Defense (DoD or Department) requires a secure and resilient supply chain to ensure the development, production, and sustainment of capabilities critical to national security. The DoD supply chain is targeted by adversaries with increasing frequency and sophistication, and to devastating effect. Therefore, implementation of cybersecurity standards and enforcement mechanisms are critically important. Executive Order (E.O.) 14028, 'Improving the Nation's (printed page 83172) Cybersecurity,' emphasizes the need to strengthen cybersecurity protections for both the Federal Government and the private sector. Nation-state adversaries attack the U.S. supply chain for a myriad of reasons, including exfiltration of valuable technical data (a form of industrial espionage); disruption to control systems used for critical infrastructure, manufacturing, and weapons systems; corruption of quality and assurance across a broad range of product types and categories; and manipulation of software to achieve unauthorized access to connected systems and to degrade the integrity of system operations. For example, since September 2020, major cyber-attacks such as the SolarWinds, [31] Colonial Pipeline, Hafnium, [32]

, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence. (B) From subsections (d) and (f) of 5 U.S.C. 552a because providing access to investigative records and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under 5 U.S.C. 552a would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) of 5 U.S.C. 552a because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) of 5 U.S.C. 552a because this SOR is compiled for investigative purposes and is exempt from the access provisions of subsections (d) and (f). (E) From subsection (e)(4)(I) of 5 U.S.C. 552a because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. § 310.26 National Reconnaissance Office (NRO) exemptions. (a) All systems of records maintained by

the NRO shall be exempt from the requirements of 5 U.S.C. 552a(d) pursuant to 5 U.S.C. 552a(k)(1) to the extent that the system contains any information properly classified under Executive Order 12958 and which is required by the Executive Order to be withheld in the interest of national defense of foreign policy. This exemption, which may be applicable to parts of all systems of records, is necessary because certain record systems not otherwise specifically designated for exemptions herein may contain items of information that have been properly classified.

For the purposes of this analysis, it is assumed that the cost to a civilian agency to validate a contractor's system security plan (see section IV.C.2.e. of this preamble) will be similar to the cost for DoD to perform a strategic High Confidence Level Assessment, approximately \$51,097 per action. Therefore, the total annual estimated cost for civilian agencies to perform these validations is \$5,620,670 (110 non-defense contractor system security plan reviews * \$51,097/review). 7. Training Government Employees on New Requirements for CUI It is expected that the Government contracting officers, contract specialists, contracting officer representatives, and others involved in the acquisition process, such as program managers and those involved in the development of requirements documents, will be required to become familiar with the technical requirements of this rule and receive additional training. While the requirement to remain current on policies for Government procurement, such as changes to the FAR, is considered a part of the normal duties of such individuals, there is expected to be specialized Government training on this topic, the cost of which is attributed to this rule. It is estimated that 250,000 Government employees may need to take 30 minutes of specialized training at an average wage rate equivalent to a GS-12, step 5, Government employee. Therefore, the estimated annual training cost is \$9,000,000 (250,000 employees * 0.5 hours/employee * \$72/hour). E. Total Costs The total estimated costs (in billions) associated with this FAR rule over a ten-year period are as follows: Government Cost Undiscounted 2 percent Present Value \$22.32 \$20.10 Annualized 2.23 2.24 Undiscounted public and Government costs (in billions) by year over the ten-year period are summarized in the following table: (printed page 4286) Year 1 Year 2 Year 3 Year 4 Year 5 Year 6 Year 7 Year 8 Year 9 Year 10 \$2.75 \$2.17 \$2.17 \$2.17 \$2.17 \$2.17 \$2.17 \$2.17 \$2.17 \$2.17 F. Alternatives Considered 1. Status Quo Absent this FAR rule, agencies will continue to employ ad hoc, agency-specific policies to manage CUI. This approach can cause agencies to mark and handle this information inconsistently and inefficiently, and forces defense and non-defense contractors to establish procedures and internal controls to meet different civilian and defense agency approaches for marking and handling CUI. This approach was determined to be counter to the purpose of the Federal Acquisition Regulations System, which was established for the codification and publication of uniform policies and procedures for acquisition by all executive agencies (see FAR 1.101). 2. No Standard Form

3.1.1. 3.1.1. 3.1.1) - Agencies will benefit if their MFA solutions support multiple authenticator types and methods.

5.1.2.3.Updates Participants were asked how updates to standards impacted their product lifecycle. Sometimes, updates to standards specifications can be disruptive: Two participants commented on interdependencies of standards, and that problems with updates to all applicable documents aren't always closely coordinated:

. However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Records maintained in connection with providing protective services to the President and other individuals under 18 U.S.C. 3506 , may be exempt pursuant to 5 U.S.C. 552a(k)(3) . (C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be, exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (D) Any portion of this system that falls under the provisions of 5 U.S.C. 552a(k)(2) , (k)(3), (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3) ; (d); (e)(1); (e)(4)(G), (H) and (I); and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) , (k)(3), (k)(5). (iii) Reasons. (A) From subsection (c)(3) because it will enable DSS to conduct certain investigations and relay law enforcement information without compromise of the information, protection of investigative techniques and efforts employed,

and identities of confidential sources who might not otherwise come forward and who furnished information under an express promise that the sources' identity would be held in confidence (or prior to the effective date of the Act, under an implied promise); (B) From subsections (e)(1), (e)(4)(G), (H), and (I) because it will provide protection against notification of investigatory material including certain reciprocal investigations and counterintelligence information, which might alert a subject to the fact that an investigation of that individual is taking place, and the disclosure of which would weaken the on-going investigation, reveal investigatory techniques, and place confidential informants in jeopardy who furnished information under an express promise that the sources' identity would be held in confidence (or prior to the effective date of the Act, under an implied promise); (C) From subsections (d) and (f) because requiring DSS to grant access to records and agency rules for access and amendment of records would unfairly impede the agency's investigation of allegations of unlawful activities. To require DSS to confirm or deny the existence of a record pertaining to a requesting individual may in itself provide an answer to that individual relating to an on-going investigation. The investigation of possible unlawful activities would be jeopardized by agency rules requiring verification of record, disclosure of the record to the subject, and record amendment procedures. (2) System identifier and name. V5-01, Investigative Files System. (i) Exemption.

The five functions are Identify, Protect, Detect, Respond, and Recover. NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

APPENDIX B PAGE 96 This publication is available free of charge from:

<https://doi.org/10.6028/NIST.SP.800-37r2> cybersecurity framework profile [NIST CSF] A representation of the outcomes that a particular system or organization has selected from the Framework Categories and Subcategories. cybersecurity framework subcategory [NIST CSF] The subdivision of a Category into specific outcomes of technical and/or management activities. derived requirements [SP 800-160 v1] A requirement that is implied or transformed from a higher-level requirement. Note 1: Implied requirements cannot be assessed since they are not contained in any requirements baseline. The decomposition of requirements throughout the engineering process makes implicit requirements explicit, allowing them to be stated and captured in appropriate baselines and allowing associated assessment criteria to be stated. Note 2: A derived requirement must trace back to at least one higher-level requirement. detect (CSF function) [NIST CSF] Develop and implement the appropriate activities to identify the occurrence of a cybersecurity event. developer A general term that includes developers or manufacturers of systems, system components, or system services; systems integrators; vendors; and product resellers. Development of systems, components, or services can occur internally within organizations or through external entities. enterprise [CNSSI 4009] An organization with a defined mission/goal and a defined boundary, using systems to execute that mission, and with responsibility for managing its own risks and performance. An enterprise may consist of all or some of the following business aspects: acquisition, program management, human resources, financial management, security, and systems, information and mission management. See organization. enterprise architecture [44 USC 3601] A strategic information asset base, which defines the mission; the information necessary to perform the mission; the technologies necessary to perform the mission; and the transitional processes for implementing new technologies in response to changing mission needs; and includes a baseline architecture; a target architecture; and a sequencing plan. environment of operation [OMB A-130] The physical surroundings in which an information system processes, stores, and transmits information. event [SP 800-61, Adapted] Any observable occurrence in a network or information system. executive agency [OMB A-130] An executive department specified in 5 U.S.C. Sec. 101; a military department specified in 5 U.S.C. Sec. 102; an independent establishment as defined in 5 U.S.C. Sec. 104(1); and a wholly owned Government corporation fully subject to the provisions of 31 U.S.C. Chapter 91.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The

term security will be used as a shorthand for 'cybersecurity' or 'information security.' Reference to physical security is different and will be labeled as such. · Physical security

) requires cost-benefit and other analyses before any rule making if the rule will include a
·Federal mandate that may result in the expenditure by State, local, and tribal governments, in the aggregate, or by the private sector, of \$100,000,000 or more (adjusted annually for inflation) in any 1 year.· The current inflation-adjusted statutory threshold is \$112,300,000. FDA has determined that this final rule does constitute a significant rule under the Unfunded Mandates Reform Act. Most of the requirements of the Unfunded Mandates have been fulfilled in the Executive Order 12866 analysis in the PRIA. The requirements under the Unfunded Mandates Act of 1995 include assessing the rule's effects on future costs; productivity; particular regions, communities, or industrial sectors; economic growth; full employment; job creation; and exports. Future Costs The future costs from the recordkeeping rule include the recurring costs, which reach their long-term value in the third year after promulgation of the final rule. These costs will be incurred by all domestic facilities that manufacture, process, pack, transport, distribute, receive, hold, or import food except very small retail facilities. Recurring costs from collecting new information as well as the learning costs for new entrants will be incurred in each future year. An hourly burden of 30 minutes a week was estimated for the additional monitoring and recordkeeping that will be required from this final rule. This hourly burden estimate was modified for convenience stores to allow for structural differences assumed in their operations. Refer to the PRIA for a fuller illustration of the future costs of the final rule. Table 24.·Future Costs Mean Low High Year 3 and later years \$123,209,200 \$121,980,000 \$125,788,000 Particular Regions, Communities, or Industrial Sectors The costs of the establishment and maintenance of records will be shared among all domestic manufacturers, processors, packers, transporters, receivers, holders, and importers of food, except very small retail facilities that are exempted from the final rule. The higher costs incurred by domestic suppliers as a result of these regulations will mostly be passed on to consumers in the form of higher food prices. Because consumer demand for food is highly inelastic, almost all of the higher costs incurred by food suppliers will be passed on to consumers. Consequently, higher food prices will reduce real incomes for all consumers. However, we believe that the benefits from these regulations will justify the reduction in real incomes. These benefits are measured as an improved ability by the FDA to respond to and contain threats of serious adverse health consequences from accidental or deliberate contamination of food. National Productivity, Economic Growth, Job Creation, and Full Employment

, because it will not result in an annual effect on the economy of \$100 million or more; a major increase in costs or prices for consumers, individual industries, Federal, State, or local government agencies, or geographic regions; or significant adverse effects on competition, employment, investment, productivity, innovation, or on the ability of United States-based enterprises to compete with foreign-based enterprises in domestic and export markets. Sec. 202, Public Law 104-4 , ·Unfunded Mandates Reform Act· It has been certified that 32 CFR part 236 does not contain a Federal mandate that may result in expenditure by State, local and tribal governments, in aggregate, or by the private sector, of \$100 million or more in any one year. Public Law 96-354, ·Regulatory Flexibility Act· (5 U.S.C. 601) It has been certified that 32 CFR part 236 is not subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would not, if promulgated, have a significant economic impact on a substantial number of small entities. DIB participation in the DIB CS/IA Program is voluntary. Public Law 96-511, ·Paperwork Reduction Act· (44 U.S.C. Chapter 35) Sections 236.4 and 236.5 and 236.7 of this interim final rule contain information collection requirements. DoD has submitted the following proposal to Office of Management and Budget (OMB) under the provisions of the Paperwork Reduction Act (44 U.S.C. Chapter 35). Comments are invited on: (a) Whether the proposed collection of information is necessary for the proper performance of the functions of DoD, including whether the information will have practical utility; (b) the accuracy of the estimate of the burden of the proposed information collection; (c) ways to enhance the quality, utility, and clarity of the information to be collected; and (d) ways to minimize the burden of the information collection on respondents, including the use of automated collection techniques or other forms of information technology. (a) Title: Defense Industrial Base Cyber Security/Information Assurance (DIB CS/IA) Points of Contact Information. Type of Request: New. Projected Responses per Respondent: One response is required initially and thereafter only on an ·as needed/required· basis, as changes to the points of contact occur. Annual Responses: 275, which includes the additional responses required on an ·as needed/required· basis. Average Burden per Response: 20 minutes. Annual Burden Hours: Total

annual burden for respondents 92 hours. Total Annualized Cost to Respondents: One-time cost of ~\$12 per respondent. Total cumulative annual cost for 250 respondents (275 responses) is \$3,337. Needs and Uses:

At Level 2, CMMC adds a requirement for contractors and applicable subcontractors to verify that all applicable security requirements outlined in NIST SP 800-171 Rev 2 and required via DFARS clause 252.204-7012 have been implemented. As determined by DoD, program contracts will include either a CMMC Level 2 Self-Assessment requirement or a CMMC Level 2 Certification Assessment requirement to verify a contractor's implementation of the CMMC Level 2 security requirements. Selected requirements are allowed to have a Plan of Action and Milestones (POA&M) that must be closed out within 180 days of the assessment (see § 170.21 for details on POA&M). This self-assessment must be performed on a triennial basis and the results must be entered electronically in SPRS (see § 170.16 for details on CMMC Level 2 Self-Assessment requirements and procedures, and specifically § 170.16(a)(1)(i) for information collection). c. Affirmation Requirements (New) A senior official from the prime contractor and any applicable subcontractor will be required to affirm continuing compliance with the specified security requirements after every assessment, including POA&M closeout, and annually thereafter. Affirmations are entered electronically in SPRS (see § 170.22 for details on Affirmation requirements and procedures). 3. Contracts or Subcontracts With a CMMC Level 2 Certification Assessment Requirement a. Security Requirements For CMMC Level 2 Certification Assessment, contractors and applicable subcontractors are already required to implement the security requirements currently required by the DFARS clause 252.204-7012, which are aligned with NIST SP 800-171 Rev 2. b. Assessment Requirements (New) At Level 2, CMMC adds a requirement for contractors and applicable subcontractors to verify that all applicable security requirements outlined in NIST SP 800-171 Rev 2 and required via DFARS clause 252.204-7012 have been implemented. As determined by DoD, program contracts will include either a CMMC Level 2 Self-Assessment requirement or a CMMC Level 2 Certification Assessment requirement to verify a contractor's implementation of the CMMC Level 2 security requirements. Selected requirements are allowed to have a POA&M that must be closed out within 180 days of the assessment (see § 170.21 for details on POA&M). The final certification will have up to a three-year duration. The third-party assessment organization will enter the assessment information electronically into the CMMC Enterprise Mission Assurance Support Service (eMASS), that will electronically transmit the assessment results into SPRS (see § 170.17 for details on CMMC Level 2 Certification Assessment requirements and procedures, and specifically § 170.17(a)(1)(i) for information collection). c. Affirmation Requirements (New)

During the processing of a Freedom of Information Act/Privacy Act request (which may include access requests, amendment requests, and requests for review for initial denials of such requests), exempt materials from other systems of records may, in turn, become part of the case record in this system. To the extent that copies of exempt records from those other systems of records are entered into this system, the Defense Logistics Agency claims the same exemptions for the records from those other systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1) through (7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy; to avoid interference during the conduct of criminal, civil, or administrative actions or investigations; to ensure protective services provided the President and others are not compromised; to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations; to preserve the confidentiality and integrity of Federal testing materials; and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (7) System identifier and name. S240.28 DoD (Specific exemption), Case Adjudication Tracking System (CATS). (i) Exemption. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (printed page 14778) (B) Therefore, portions of this system may be exempt pursuant to 5 U.S.C. 552a(k) (5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d)(1)(2)(3)(4), and (e)(1). (i) Authority. 5 U.S.C.

We also recognized that entities could minimize risk through their security practices, but likely could never completely eliminate all risk. In the preamble to the 2003 Final Rule, the Department acknowledged that there is no such thing as a totally secure system that carries no risks to security. [88] The Department opined that Congress' intent in the use of the word 'ensure' in section 1173(d) of the SSA was to set an exceptionally high goal for the security of ePHI. However, we also recognized that Congress anticipated that some trade-offs would be necessary, and that 'ensuring' protection did not mean doing so without any regard to the cost. [89] As such, the Department explained that we expected a covered entity to protect that information to the best of its ability. [90] Thus, a covered entity would be expected to balance the identifiable risks to and vulnerabilities of ePHI with the cost of various protective measures, while also taking into consideration the size, complexity, and capabilities of the covered entity. [91] In the 2003 Final Rule, the Department introduced the concept of 'addressable' implementation specifications, which it distinguished from 'required' implementation specifications. The goal was to provide covered entities with even more flexibility. [92] While none of the implementation specifications were optional, designating some of the implementation specifications as addressable provided each covered entity with the ability to determine whether certain implementation specifications were reasonable and appropriate safeguards for that entity, based on its risk analysis, risk mitigation strategy, previously implemented security measures, and the cost of implementation. [93]

3. 2009 Delegation of Authority On October 7, 2003, the Secretary delegated authority for administering and enforcing the Security Rule to the Administrator of the Centers for Medicare & Medicaid Services (CMS). [94] The Secretary issued a notice on August 4, 2009, superseding the previous delegation and replacing it with a delegation authority to the Director of OCR effective July 27, 2009. [95]

4. 2013 Omnibus Rulemaking Following the enactment of the HITECH Act, the Department issued an NPRM, entitled 'Modifications to the HIPAA Privacy, Security, and Enforcement Rules Under the Health Information Technology for Economic and Clinical Health [HITECH] Act' ('2010 Proposed Rule'), [96] to propose implementation of certain HITECH Act requirements. In the 2010 Proposed Rule, the Department noted that it had not amended the Security Rule since 2003. [97] We further explained that information gleaned from contact with the public since that time, OCR's enforcement experience, and technical corrections needed to eliminate ambiguity provided the impetus for the Department's actions to propose certain regulatory changes beyond those required by the HITECH Act. [98]

Contractor employees shall also take any additional training described in the SF XXX sections on training. This additional training augments the general CUI training and may include specialized training for a particular category of CUI or for certain employees handling CUI in a specific situation, or other similar circumstances. (g) CUI incidents. (1) For CUI in a Federally-controlled facility, the Contractor shall report CUI incidents in accordance with agency policy. (2) For CUI in a non-Federally-controlled facility, the Contractor shall report: (i) Any suspected or confirmed CUI incident to the agency website or single point of contact identified in Part C, Section IV of the SF XXX; if there is no point of contact identified there the Contractor should contact the Contracting Officer for instructions; (ii) Within 8 hours of discovery; and (iii) As many of the applicable data elements located at <https://dibnet.dod.mil/portal/intranet/> as are available in the initial report and provide any remaining applicable data elements as soon as they become available. (3) When the Contractor discovers a suspected or confirmed CUI incident, the Contractor shall: (i) Determine and inventory what CUI was or could have been improperly accessed, created, collected, used, processed, stored, maintained, disseminated, disclosed, or disposed of; (ii) Construct a timeline of user activity; (iii) Determine methods and techniques used to access CUI; and (iv) Cooperate and exchange information with agency officials, as determined necessary by the agency, in order to effectively report and manage a suspected or confirmed CUI incident. (4) If the suspected or confirmed CUI incident has occurred on an information system, preserve and protect images of all known affected information systems and all relevant monitoring and packet capture data until the Government declines interest or 90 days from the date of the submission of the report passes without the Government requesting the media and data, whichever is sooner. (5) Unmarked or mismarked CUI is not considered a CUI incident unless the mismarking or lack of marking has resulted in the mishandling or improper dissemination of the information. (6) If the Contractor is a FedRAMP authorized (Joint Authorization Board or Agency) cloud service provider, the Contractor shall also report to the point(s) of contact specified in the FedRAMP incident reporting guidelines as documented in the Cloud Service Provider Incident Response Plan. (7) The reporting requirements of

this clause do not relieve the Contractor from the requirement to follow any applicable laws, regulations, or policies outside of this clause. (8) If the Contractor is determined to be at fault for a CUI incident (e.g.,

The Department also recognizes that there may be some costs that are not readily quantifiable, notably, actions that regulated entities may take to comply with existing requirements more fully as a result of proposed clarifications. For example, this would include completing a technology asset inventory, which is a baseline expectation for the existing requirement of conducting a risk assessment; documenting completion of existing requirements; adding more specificity to the required contingency plan, such as designating staff roles with specific responsibilities when a contingency occurs; testing safeguards as part of reviewing and updating policies and procedures and technical controls; and deploying encryption for ePHI in a more concerted manner (including documenting provision of notification in response to individuals' access requests for transmission of ePHI in an unencrypted manner and has been informed of the risks associated with the transmission, receipt, and storage of unencrypted ePHI). These activities are specified in the NPRM, but they would be more in the nature of clarifications to and increased specificity of existing requirements. Because the degree of additional effort by regulated entities to meet these requirements would be dependent on multiple factors and likely to be highly variable, the additional cost is difficult to quantify. We acknowledge that there may be a small burden associated with documenting that an individual was informed of the risks of unencrypted transmission of ePHI; however, we believe there are few requests that fall into this category. Because we do not have a basis to make an estimate, we have requested data on potential burdens associated with this proposed exception to the proposed standard for encryption in the preamble discussion of 45 CFR 164.312 . The cost of complying with the exceptions to encryption and MFA for medical devices authorized by the U.S. Food & Drug Administration for marketing may depend in part on the extent to which a regulated entity relies on legacy devices because the regulated entity may be required to adopt compensating controls. New devices are likely to have encryption and MFA built into them, not requiring compensating controls. The Department is unable to estimate the range of costs to adopt compensating controls for legacy devices because there is no reliable data to accurately assess the extent to which legacy devices are used in the United States. [939] The Department requests comment on the number of legacy devices in use and the costs of applying compensating controls to such devices. 2. Baseline Conditions

3.1.3 | 3.1.3 Automate Selected Defect Checks The sub-steps for automating selected defect checks are described in this section.

The purpose of a MAC is to authenticate both the source of a message and its integrity without the use of any additional mechanisms. HMACs have two functionally distinct parameters, a message input and a secret key known only to the message originator and intended receiver(s). Additional applications of keyed-hash functions include their use in challenge-response identification protocols for computing responses, which are a function of both a secret key and a challenge message. Providing a way to check the integrity of information transmitted over or stored in an unreliable medium is a prime necessity in the world of open computing and communications. Mechanisms that provide such integrity checks based on a secret key are usually called message authentication codes (MACs). Typically, message authentication codes are used between two parties that share a secret key in order to authenticate information transmitted between these parties. This Standard defines a MAC that uses a cryptographic hash function in conjunction with a secret key. This mechanism is called HMAC [HMAC]. HMAC shall use an Approved cryptographic hash function [FIPS 180-3]. HMAC uses the secret key for the calculation and verification of the MACs.

3.5.3 | Attribute Transformation... 3.5.3 Attribute Transformation Attributes that are typically assigned to very large numbers of subjects and many types of objects can lead to administrative difficulties from different perspectives for access control.

- improvement opportunities for the organization's policies, plans, processes, procedures, and practices that support cybersecurity risk management to inform efforts under all six Functions. - PROTECT (PR) -Safeguards to manage the organization's cybersecurity risks are used. Once assets and risks are identified and prioritized, PROTECT supports the ability to secure those assets to prevent or lower the likelihood and impact of adverse cybersecurity events, as well as to increase the likelihood and impact of taking advantage of opportunities. Outcomes covered by this Function

include identity management, authentication, and access control; awareness and training; data security; platform security (i.e., securing the hardware, software, and services of physical and virtual platforms); and the resilience of technology infrastructure. - DETECT (DE) -Possible cybersecurity attacks and compromises are found and analyzed. DETECT enables the timely discovery and analysis of anomalies, indicators of compromise, and other potentially adverse events that may indicate that cybersecurity attacks and incidents are occurring. This Function supports successful incident response and recovery activities. - RESPOND (RS) -Actions regarding a detected cybersecurity incident are taken. RESPOND supports the ability to contain the effects of cybersecurity incidents. Outcomes within this Function cover incident management, analysis, mitigation, reporting, and communication. - RECOVER (RC) -Assets and operations affected by a cybersecurity incident are restored. RECOVER supports the timely restoration of normal operations to reduce the effects of cybersecurity incidents and enable appropriate communication during recovery efforts. Cybersecurity risk management is essential for addressing privacy risks related to the loss of the confidentiality, integrity, and availability of individuals' data. For example, data breaches could lead to identity theft.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. These capabilities were developed in the context of NISTIR 8259, Foundational Cybersecurity Activities for IoT Device Manufacturers [2], which discusses considerations for manufacturers to help guide them in choosing and implementing the device cybersecurity capabilities their IoT devices will provide. NISTIR 8259 also defines terminology and concepts that provide critical context for understanding device cybersecurity capabilities as one part of the entire IoT cybersecurity ecosystem. Thus, though both NISTIR 8259 and this publication have manufacturers as the intended audience, the considerations and capabilities discussed across the two publications can be used by manufacturers, integrators, or consumers.

Additionally, the Department proposes to modify the general requirements of paragraph (a)(2) to require each regulated entity to protect against any reasonably anticipated threats or hazards to the confidentiality, integrity, or availability of all ePHI, instead of to the security or integrity of ePHI. We believe that this proposal would better align this requirement with the general requirement at 45 CFR 164.306(a)(1), and confidentiality, integrity, and availability are generally considered the three basic elements of security. [422] Additionally, the Department proposes a minor change to paragraph (a)(3) to refer specifically to ePHI, rather than using a more general term. We believe that both proposals would constitute technical revisions and that neither would alter the meaning of 45 CFR 164.306(a)(2) or (3), respectively. Finally, the Department proposes to modify paragraph (a)(4) so that each regulated entity would be required to ensure that its workforce complies not only with the Security Rule, but also all administrative, physical, and technical safeguards implemented in accordance with this subpart. These proposals would better align the language of the general requirements in paragraph (a) of 45 CFR 164.306 with the statute [423] and 45 CFR 164.530(c). [424] These proposals are also consistent with our proposals to revise the introductory language for each of the safeguard provisions to clarify the provisions therein would be the minimum regulated entities are to implement, i.e., that the security measures required by the Security Rule constitute a floor of protections, not a ceiling.

b. Section 164.306(b)-Flexibility of Approach The Department's proposals generally retain the flexible approach described in paragraph (b). As discussed above, the Security Rule carefully balances the benefits of safeguarding against risks to security and the burdens of implementing protective measures by, for example, enabling regulated entities to take into account specified factors when determining how to implement security measures in a manner that complies with the

Security Rule. To acknowledge the rapid evolution of technology and increasing threats, the Department proposes to clarify (printed page 933)

3.1.2 | Time Spent on Security Awareness ... 3.1.2 Time Spent on Security Awareness ## Focus Groups
The focus group demographic survey asked what percentage of time participants spend on their security awareness duties.

media [FIPS 200] Physical devices or writing surfaces including, but not limited to, magnetic tapes, optical disks, magnetic disks, Large-Scale Integration memory chips, and printouts (but excluding display media) onto which information is recorded, stored, or printed within a system.

NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

APPENDIX B PAGE 101 This publication is available free of charge from:

<https://doi.org/10.6028/NIST.SP.800-37r2> moderate-impact system [FIPS 200] A system in which at least one security objective (i.e., confidentiality, integrity, or availability) is assigned a FIPS Publication 199 potential impact value of moderate and no security objective is assigned a potential impact value of high. national security system [44 USC 3552] Any system (including any telecommunications system) used or operated by an agency or by a contractor of an agency, or other organization on behalf of an agency: (i) the function, operation, or use of which involves intelligence activities; involves cryptologic activities related to national security; involves command and control of military forces; involves equipment that is an integral part of a weapon or weapons system; or is critical to the direct fulfillment of military or intelligence missions (excluding a system that is to be used for routine administrative and business applications, for example, payroll, finance, logistics, and personnel management applications); or (ii) is protected at all times by procedures established for information that have been specifically authorized under criteria established by an Executive Order or an Act of Congress to be kept classified in the interest of national defense or foreign policy. network A system implemented with a collection of interconnected components. Such components may include routers, hubs, cabling, telecommunications controllers, key distribution centers, and technical control devices. network access Access to a system by a user (or a process acting on behalf of a user) communicating through a network (e.g., a local area network, a wide area network, and Internet). operational technology Programmable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment). These systems/devices detect or cause a direct change through the monitoring and/or control of devices, processes, and events. Examples include industrial control systems, building management systems, fire control systems, and physical access control mechanisms. operations technology See operational technology. organization [FIPS 200, Adapted] An entity of any size, complexity, or positioning within an organizational structure (e.g., federal agencies, private enterprises, academic institutions, state, local, or tribal governments, or as appropriate, any of their operational elements). organizationally-tailored control baseline A control baseline tailored for a defined notional (type of) information system using overlays and/or system-specific control tailoring, and intended for use in selecting controls for multiple systems within one or more organizations.

DFARS 204.7603, Procedures, was updated under paragraph (a), Item Risk, to clarify that a SPRS item risk search is required for any end product that did not have an item risk search performed prior to solicitation to ensure that item risk searches in SPRS only occur if an end product did not have an item risk search performed prior to solicitation; and paragraph (b), Price Risk, applies when procuring a service or an end product identified by an available material identifier. An editorial change was made throughout to correct an administrative error by removing the words "or services" from the definition of "item risk", as item risk does not apply to services. III. Applicability to Contracts at or Below the Simplified Acquisition Threshold, for Commercial Services, and for Commercial Products, Including Commercially Available Off-the-Shelf Items This rule creates a new solicitation provision, DFARS 252.204-7024, Notice on the Use of the Supplier Performance Risk System. The provision at DFARS 252.204-7024 is prescribed at DFARS 204.7604 for use in in solicitations for supplies and services, including solicitations using FAR part 12 procedures for the acquisition of commercial products and commercial services. The provision is applicable to acquisitions at or below the simplified acquisition threshold (SAT) and to acquisitions of commercial products, including commercially available off-the-shelf (COTS) items, and commercial services. Not applying this provision to contracts at or below the SAT and for the acquisition of

commercial products, including COTS items, and commercial services would exclude contracts intended to be covered by this rule and undermine the overarching purpose of the rule. Consequently, DoD is applying the rule to contracts below the SAT, for the acquisition of commercial services, and for the acquisition of commercial products, including COTS items. IV. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. V. Congressional Review Act As required by the Congressional Review Act (5 U.S.C. 801-808

Under the proposed transition provisions, a business associate would be permitted to create, receive, maintain, or transmit ePHI pursuant to an existing business associate agreement or other written arrangement with another regulated entity that does not require the regulated entity to obtain satisfactory assurances that meet the requirements of the revised Security Rule for up to one year after the revised Security Rule becomes effective, assuming that a final Security Rule is published; and that the agreement is compliant with the Security Rule at the time the final rule is published and that it is not renewed or modified between the effective and compliance dates. [870] The transition provisions would also allow for the business associate to create, receive, maintain, or transmit ePHI on behalf of another regulated entity where the existing business associate agreement does not require that the regulated entity verify that the (printed page 987) business associate has deployed technical safeguards in accordance with the Security Rule under the same circumstances as those described above. [871] During the transition period, the Department proposes to allow a business associate to create, receive, maintain, or transmit ePHI pursuant to a business associate agreement or other written arrangement with another regulated entity without including in the agreement that the business associate will: (1) comply with the revised Security Rule; [872] (2) ensure that any subcontractors that create, receive, maintain, or transmit ePHI on behalf of the business associate agree to comply with the revised Security Rule by entering into a business associate agreement or other arrangement that meets the requirements of the revised rule; [873] and (3) report to the covered entity [874] activation of its contingency plan. [875] Additionally, the Department intends that, in cases where a contract renews automatically without any change in terms or other action by the parties (also known as "evergreen contracts"), such contracts would be eligible for the extension if they automatically renew between the effective and compliance dates. Thus, regulated entities with an evergreen contract will be deemed to be in compliance with the Security Rule's requirements for business associate agreements or other written arrangements and such deemed compliance would not terminate when these contracts automatically renew. These transition provisions would apply to written contracts or other written arrangements as specified above.

The language, which has been revised and relocated to 252.245-7004(j)(4), specifies that informal bid procedures shall be used unless the plant clearance officer directs otherwise. Comment: A respondent recommended that formal sales be considered a part of the Contract Data Requirements List (CDRL). DoD Response: There is no basis for such policy. Including this on the CDRL would make the Government liable for directly reimbursing a contractor for costs incurred in conducting surplus property sales. However, such expenses are a normal part of contractor responsibilities under FAR 52.245-1(b)(2) and are not subject to direct reimbursement. Comment: A respondent recommended removing the dollar threshold at 252.245-70XX(l)(6) and requiring the plant clearance officer, not the contractor, to send the sales notice to FedBizOps. DoD Response: The plant clearance officer, not the contractor, is the appropriate sender of the sales notice; therefore, the requirement has been deleted. A more general requirement on the use of FedBizOps has been included in the DFARS companion resource, Procedures, Guidance, and Information (PGI) for the plant clearance officer. Comment: A respondent recommended changing the second sentence of 252.245-70XX(e)(9)(7) to, "(b)id openings will be submitted to the plant clearance officer, either electronically or manually, two copies of the bid abstract." DoD Response: The language has been revised and relocated to paragraph (j)(8) of 252.245-7004, and clarifies that the contractor shall provide two copies of the bid abstract to the plant clearance officer. Comment: A respondent recommended deleting the phrase "(f)forwarded to the plant clearance officer" from 252.245-70XX(c), Proceeds from sale of surplus inventory. DoD Response: The language at 252.245-7004(c) has been clarified to require proceeds to

be forwarded to the contracting officer or plant clearance officer, credited to the Government through a settlement agreement, credited to the contract, applied to the contract as directed by the contracting officer, or forwarded to the plant clearance officer unless otherwise provided for in the contract. Comment: In reference to 252.245-70XX (I), a respondent asked if plant clearance officers must draw up and provide terms and conditions for the contractor to use on surplus sales. The respondent also requested that terms and conditions be included in this clause. DoD Response: Contractors are required to use Government-provided sales terms and conditions. This is not (printed page 52141)

- then the subsequent treatment (and full life cycle costs of each) can be estimated more fully. - A total cost of operations analysis might help avoid a situation where risk practitioners consider only the direct and immediate expense of treating a risk (or pursuing an opportunity). For example, a manager might list the direct cost of a network firewall appliance to mitigate the risk scenario of an external hacker exfiltrating corporate secrets through a web server vulnerability. The response costs should also include hardware and software maintenance of the device, installation, operational labor, and -eventually -secure disposal of that appliance.

(2) The Components reserve the discretionary authority, and have the obligation, to impose any security procedure, safeguard, or restriction they believe necessary to ensure that unauthorized access to classified information is effectively precluded and that performance of classified contracts, as defined in DoD 5220.22-M, is not adversely affected by FOCI. (b) Procedures · (1) Criteria. A U.S. company is considered to be under FOCI whenever a foreign interest has the power, direct or indirect (whether or not exercised, and whether or not exercisable through the ownership of the U.S. company's securities, by contractual arrangements or other means), to direct or decide matters affecting the management or operations of the company in a manner that may result in unauthorized access to classified information or may adversely affect the performance of classified contracts. (2) FOCI Analysis. Conducting an analysis of available information on a company to determine the existence, nature, and source of FOCI is a critical aspect of evaluating previously uncleared companies for FCLs and also in determining continued eligibility of contractors for FCLs. (i) A U.S. company determined to be under FOCI is ineligible for an FCL unless and until security measures have been put in place to mitigate FOCI. (ii) In making a determination as to whether a company is under FOCI, DSS will consider the information provided by the company or its parent entity on the Standard Form (SF) 328, ·Certificate Pertaining to Foreign Interests,· (available at <http://www.dtic.mil/whs/directives/infomgt/forms/eforms/sf0328.pdf>) and any other relevant information (e.g., filings with the Securities and Exchange Commission (for publicly traded companies), articles of incorporation, by-laws, and loan and shareholder agreements, as well as other publicly available information about the company. Depending on specific circumstances (e.g., extensive minority foreign ownership at a cleared subsidiary in the corporate family), DSS may request one or more of the legal entities that make up a corporate family to submit individual SF 328s and will determine the appropriate FOCI action plan(s) that must be put in place. (iii) When a contractor has been determined to be under FOCI, the primary consideration will be the safeguarding of classified information. DSS is responsible for taking whatever interim action is necessary to safeguard classified information, in coordination with other affected agencies as appropriate consistent with §.117.54.

MA.L2-3.7.6 · Maintenance Personnel CMMC Assessment Guide · Level 2 | Version 2.13 156 FURTHER DISCUSSION Individuals without proper permissions must be supervised while conducting maintenance on organizational machines. Consider creating temporary accounts with short- term expiration periods rather than regular user accounts. Additionally, limit the permissions and access these accounts have to the most restrictive settings possible. Example One of your software providers has to come on- site to update the software on your company-s computers. You give the individual a temporary logon and password that expires in 12 hours and is limited to accessing only the computers necessary to complete the work [a]. This gives the technician access long enough to perform the update. You monitor the individual-s physical and network activity while the maintenance is taking place [a] and revoke access when the job is done. Potential Assessment Considerations · Are there processes for escorting and supervising maintenance personnel without required access authorization (e.g., vendor support personnel, short- term maintenance contractors) during system maintenance [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.7.6

To provide the DoD with an automated system to clear and audit travel within the United States

European Command's area of responsibility and to ensure compliance with the specific clearance requirements outline in the DoD Foreign Clearance Guide; to provide individual travelers with intelligence and travel warnings; and to provide the Defense Attaché and other DoD authorized officials with information necessary to verify official travel by DoD personnel. Routine uses of records maintained in the system, including categories of users and the purposes of such uses: In addition to those disclosures generally permitted under 5 U.S.C. 552a(b) of the Privacy Act, these records or information contained therein may specifically be disclosed outside the DoD as a routine use pursuant to 5 U.S.C. 552a(b)(3) as follows: To the Department of State Regional Security Officer, U.S. Embassy officials, and foreign police for the purpose of coordinating security support for DoD travelers. The DoD Blanket Routine Uses set forth at the beginning of the Army's compilation of systems of records notices also apply to this system. Policies and practices for storing, retiring, accessing, retaining, and disposing of records. Storage: Electronic storage media. Retrievability: Retrieved by individual's surname, Social Security Number and/or passport number. Safeguards: Electronic records are located in the United States European Command's Theater Requirements Automated Clearance System (TRACS) computer database with built in safeguards. Computerized records are maintained in controlled areas accessible only to authorized personnel with an official need to know access. In addition, automated files are password protected and in compliance with the applicable laws and regulations. Another built in safeguard of the system is records are access to the data through secure network. Retention and disposal: Records are destroyed 3 months after travel is completed. System manager(s) and address: Special Assistant for Security Matters, Headquarters, United States European Command, Unit 30400, P.O. Box 1000, APO AE 09131-1000. Notification procedures: Individuals seeking to determine whether information about themselves is contained in this system of records should address written inquiries to the Special Assistant for Security Matters, Headquarters, United States European Command, Unit 30400, P.O. Box 1000, APO AE 09131-1000. Requests should contain individual's full name, Social Security Number, and/or passport number. Record access procedures: Individuals seeking to access information about themselves that is contained in this system of records should address written inquiries to the Special Assistant for Security Matters, Headquarters, United States European Command, Unit 30400, P.O. Box 1000, APO AE 09131-1000. Requests should contain individual's full name, Social Security Number, and/or passport number. Contesting record procedures:

es guidelines for selecting and specifying security controls for organizations and systems supporting the executive agencies of the Federal Government to meet the requirements of FIPS Publication 200. - SP 800-53A Assessing Security and Privacy Controls in Systems and Organizations: Building Effective Assessment Plans , provides (i) guidelines for building effective security assessment plans and privacy assessment plans; and (ii) a comprehensive set of procedures for assessing the effectiveness of security controls and privacy controls employed in systems and organizations supporting the executive agencies of the Federal Government. - SP 800-60 Guide for Mapping Types of Information and Information Systems to Security Categories , assists agencies in consistently mapping security impact levels to types of: (i) information (e.g., privacy, medical, proprietary, financial, contractor sensitive, trade secret, investigation); and (ii) systems (e.g., mission critical, mission support, administrative).

(2) Do not include a person's SSN on an emergency recall roster or their spouse's name. (3) Commanders and supervisors should give consideration to those individuals with unlisted phone numbers. Commanders and supervisors should consider limiting access to an unlisted number within the unit. (g) Social Rosters. (1) Before including personal information such as a spouse's name, home addresses, home phone numbers, and similar information on social rosters or social directories, which will be shared with individuals, always ask for the individual's written consent. Without their written consent, do not include this information. (2) Collection of this information will require a Privacy Act Statement which clearly tells the individual what information is being solicited, the purpose, to whom the disclosure of the information is made, and whether collection of the information is voluntary or mandatory. (h) Disclosure of personal information on group orders. (1) Personal information will not be posted on group orders so that everyone on the orders can view it. Such a disclosure of personal information violates the Privacy Act and this part. (2) The following are some examples of personal information that should not be contained in group orders. The following list is not all-inclusive: (i) Complete SSN; (ii) Home addresses and phone numbers; or (iii) Date of birth. (i) Disclosures for established routine uses. (1) Records may be disclosed outside the DOD without the consent of the individual to whom they pertain for an established routine use. (2) A routine use shall: (i) Be compatible with and related to the

purpose for which the record was compiled; (ii) Identify the persons or organizations to which the records may be released; and (iii) Have been published previously in the Federal Register . (3) Establish a routine use for each user of the information outside the Department of Defense who needs official access to the records. (4) Routine uses may be established, discontinued, or amended without the consent of the individuals involved. However, new or changed routine uses (printed page 46064) must be published in the Federal Register at least 30 days before actually disclosing any records. (5) In addition to the routine uses listed in the applicable systems of records notices, Blanket Routine Uses for all DOD maintained systems of records have been established. These Blanket Routine Uses are applicable to every record system maintained within the DOD unless specifically stated otherwise within a particular record system. The Blanket Routine Uses are listed at appendix C of this part. (j) Disclosure accounting. (1) System managers must keep an accurate record of all disclosures made from DA Privacy Act system of records, including those made with the consent of the individual, except when records are (i) Disclosed to DOD officials who have a need to know the information to perform official government duties; or

(K) Require CMMC Ecosystem members to utilize official training content developed by a CMMC training organization approved by the CAICO in all CMMC certification courses. (iii) Ethics policy. The Ethics policy shall: (A) Require CMMC Ecosystem members to report to the Accreditation Body within 30 days of convictions, guilty pleas, or no contest pleas to crimes of fraud, larceny, embezzlement, misappropriation of funds, misrepresentation, perjury, false swearing, conspiracy to conceal, or a similar offense in any legal proceeding, civil or criminal, whether or not in connection with activities that relate to carrying out their role in the CMMC Ecosystem. (B) Prohibit harassment or discrimination by CMMC Ecosystem members in all interactions with individuals whom they encounter in connection with their roles in the CMMC Ecosystem. (C) Require CMMC Ecosystem members to have and maintain a satisfactory record of integrity and business ethics. § 170.9 CMMC Third-Party Assessment Organizations (C3PAOs). (a) Roles and responsibilities. C3PAOs are organizations that are responsible for conducting Level 2 certification assessments and issuing Certificates of CMMC Status to OSCs based on the results. C3PAOs must be accredited or authorized by the Accreditation Body in accordance with the requirements set forth. (b) Requirements. C3PAOs shall: (1) Obtain authorization or accreditation from the Accreditation Body in accordance with § 170.8(b)(3)(i) and (ii). (2) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17); and achieve and maintain compliance with ISO/IEC 17020:2012(E) (incorporated by reference, see § 170.2) within 27 months of authorization. (3) Require all C3PAO company personnel participating in the Level 2 certification assessment process to complete a Tier 3 background investigation resulting in a determination of national security eligibility. This includes the CMMC Assessment Team and the quality (printed page 83223) assurance individual. This Tier 3 background investigation will not result in a security clearance and is not being executed for the purpose of government employment. The Tier 3 background investigation is initiated using the Standard Form (SF) 86 (www.gsa.gov/reference/forms/questionnaire-for-national-security-positions). These positions are designated as non-critical sensitive with a risk designation of Moderate Risk in accordance with 5 CFR 1400.201(b) and (d) and the investigative requirements of 5 CFR 731.106(c)(2) . (4) Require all C3PAO company personnel participating in the Level 2 certification assessment process who are not eligible to obtain a Tier 3 background investigation to meet the equivalent of a favorably adjudicated Tier 3 background investigation. DoD will determine the Tier 3 background investigation equivalence for use with the CMMC Program only. (5) Comply with Foreign Ownership, Control or Influence (FOCI) by:

The proposed rule changes seek to provide clarification on safeguarding terminology and correct identified paragraph numbering errors, as well as (printed page 86291) address comments from regulated parties seeking more detail or guidance on existing requirements from the final rule published December 21, 2020. The proposed changes are mostly insignificant in that by themselves, these proposed changes create no additional requirements to current NISP policy. For example, a paragraph on subcontracting was removed because it was deemed to be guidance for the government, rather than contractors (i.e., the regulated parties). Also, the references to the Joint Personnel Adjudication System as the system of record for personnel security clearance processing were removed and replaced with the current system of record, Defense Information System for Security. These changes create no additional burden or cost to contractors; but rather seek to provide updated, accurate information. The proposed changes also seek to clarify terminology in relation to safeguarding requirements, which were initially incorporated into the final rule

published December 21, 2020 to be in line with 32 CFR part 2001. These changes are not expected to result in any changes to cost estimates or burden on the regulated parties, but rather provide a more consistent, uniform means to comply with existing NISP requirements across the federal government. Costs As stated under the Discussion of Comments and Changes section, DoD received one comment that the cost for implementing SEAD 3 was underestimated in the original rule. DoD agrees with the commenter and the cost estimates have been updated accordingly. We are including here the summary of information on the baseline cost from the original rule for reference. DCSA began the cost analysis for the baseline costs for fiscal year 2017 by randomly selecting active NISP contractor facilities that have existing DoD approval for classified storage at their own physical locations and having those facilities submit security costs. The randomly selected contractor facilities also have an active facility security clearance and a permanent Commercial and Government Entity (CAGE) Code. In addition to the randomly selected cleared facilities having approved classified storage, DCSA categorizes these contractor facilities for the survey based on the size, scope, and complexity of each contractor's security program.

required a review of agency-specific cybersecurity requirements that currently exist as a matter of law, policy, or contract to form the recommendation for the standardized contract language proposed in this rule. As a result, this rule may duplicate, overlap, or conflict with existing agency-specific cybersecurity contract clauses. Section 2. Paragraph (k) of the E.O. resolves the issue of duplication, overlap, or conflict by requiring agencies, upon final publication of this rule, to update their agency-specific cybersecurity requirements to remove any requirements that are duplicative of this rule. There are no known significant alternative approaches to the proposed rule. The Regulatory Secretariat Division has submitted a copy of the IRFA to the Chief Counsel for Advocacy of the Small Business Administration. A copy of the IRFA may be obtained from the Regulatory Secretariat Division. DoD, GSA, and NASA invite comments from small business concerns and other interested parties on the expected impact of this rule on small entities. DoD, GSA, and NASA will also consider comments from small entities concerning the existing regulations in subparts affected by the rule in accordance with 5 U.S.C. 610. Interested parties must submit such comments separately and should cite 5 U.S.C. 610 (FAR Case 2021-019), in correspondence. VII. Paperwork Reduction Act The Paperwork Reduction Act (44 U.S.C. 3501-3521) applies because the proposed rule contains information collection requirements. Accordingly, the Regulatory Secretariat Division has submitted a request for approval of a new information collection requirement concerning Standardizing Cybersecurity Requirements for Unclassified Federal Information Systems to the Office of Management and Budget. A. Public Reporting Burden for This Collection of Information 1. Submit Annual Assessment of FIS Public reporting burden for this collection of information is estimated to average 1 hour per response, including the time for reviewing instructions, searching existing data sources, gathering and maintaining the data needed, and completing and reviewing the collection of information. The annual reporting burden estimated as follows: Respondents/Recordkeepers: 27. Total Annual Responses: 54. Total Burden Hours: 54. This estimate is based on two responses per respondent. 2. Maintain and Submit a List of Operational Technology Equipment The public recordkeeping burden for this collection of information is estimated to annually require one recordkeeper who spends 80 hours per contract to maintain the list: Recordkeepers: 28. Total annual records: 28. Total recordkeeping burden hours: 2,240. The public reporting burden for this collection of information is estimated to average 1 hour per response to review and submit the list. The annual reporting burden is estimated as follows: Respondents: 6. Total Annual Responses: 6. Total Burden Hours: 6. This estimate is based on one response per respondent. 3. Submit Continuous Monitoring Strategy

means a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information (44 U.S.C. 3502(8)). Information resources, as used in this definition, includes any ICT. Information technology * * * * *

(3) * * * (ii) Is operational technology. * * * * * Internet of Things (IoT) devices

means, consistent with section 2 paragraph 4 of Public Law 116-207, devices that: (1) Have at least one transducer (sensor or actuator) for interacting directly with the physical world, have at least one network interface, and are not conventional information technology devices, such as smartphones and (printed page 68414) laptops, for which the identification and implementation of cybersecurity features is already well understood; and (2) Can function on their own and are not only able to function when acting as a component of another device, such as a processor. * * * *

* Operational technology means programmable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment). These systems or

devices detect or cause a direct change through the monitoring and/or control of devices, processes, and events. Examples of operational technology include industrial control systems, building management systems, fire control systems, and physical access control mechanisms (NIST SP 800-160 vol 2). * * * * * Telecommunications equipment means equipment used to transmit, emit, or receive signals, signs, writing, images, sounds, or intelligence of any nature, by wire, cable, satellite, fiber optics, laser, radio, or any other electronic, electric, electromagnetic, or acoustically coupled means. Telecommunications services means services used to transmit, emit, or receive signals, signs, writing, images, sounds, or intelligence of any nature, by wire, cable, satellite, fiber optics, laser, radio, or any other electronic, electric, electromagnetic, or acoustically coupled means. * * * * * PART 4-ADMINISTRATIVE AND INFORMATION MATTERS 4.1301 [Amended] 4. Amend section 4.1301 by removing from paragraphs (a) and (b) ·Federally-controlled information· and adding ·Federal information· in their places; respectively. 4.1303 [Amended] 5. Amend section 4.1303 by removing from the text ·Federally-controlled information· and adding ·Federal information· in its place. 4.1901 [Amended] 6. Amend section 4.1901 by removing the definitions of ·Information· and ·Information system·. PART 7-ACQUISITION PLANNING 7. Amend section 7.103 by· a. Removing from paragraph (q) ·information and communication technology· and adding ·information and communications technology· in its place; and b. Adding paragraph (z). The addition reads as follows. 7.103 Agency-head responsibilities. * * * * *

One comment questioned the requirement for a Tier 3 background investigation for CCPs and another suggested the validity period of CCP certification should be determined by the CAICO. Yet another comment suggested changing certification periods from 3 to 4 years for those certified prior to the rule becoming effective. One comment suggested there is insufficient clarity regarding the role CCPs may play in an assessment and another asked whether a CCPs was allowed to review more than just Level 1 requirements. Two other comments recommended updating CCP training to include Level 2 practices. Another comment noted that assessor cannot be robotic and that they must be allowed to evaluate the situation as it pertains to the company being evaluated. One comment asked for clarification on Lead CCA requirements and requested a reduction in the management experience to 2 years. Two other comments recommended adding IT and cybersecurity experience as relevant skills. One comment also recommended that Lead CCAs have industry-specific knowledge of the industry in which the OSC being assessed participates. Another comment requested clarification whether years of experience are cumulative for the Lead CCA. One comment recommended changing the name of Lead CCA and adding roles and responsibilities requirements. One stated that the rule's CCA prerequisites is too low a skill set and recommended increasing the requirements for both CCAs and Lead CCAs. While another comment noted the rule referenced both DoD Manual 8570 and DoD Manual 8140.03 and one or the other should be used. One commenter suggested that should sufficient assessors not be available to meet demand, the DoD should provide a delay or ·grace period· to meet certification requirements. Response: The CMMC rule provides detail on anticipated impacts on the DIB in the Impact and Cost Analysis summary of the preamble. Speculation on market forces on roles in the CMMC ecosystem such as CCPs and CCAs are outside of the scope of the CMMC program rulemaking. Likewise, limitations on career opportunities and associated issues such as burn-out or job satisfaction are beyond the scope of the program. The DoD updated the rule to clarify that CCAs must meet all the requirements set forth in §·170.11(b) and modified the rule in §·170.10(b)(10) to include CMMC Certified Professionals (CCPs). §·170.13(b)(6) was changed to conform to rule text in §·170.11(b)(9) and to clarify with whom information may be shared. The DoD determined the certification requirements specified in §·170.11(b)(6) meet the needs of ensuring certified assessors have the required depth of cybersecurity knowledge and experience that is beyond what the CMMC-specific training provides.

n management, because each guest OS can be derived from a parent guest OS, providing a consistent security baseline and reducing the time and effort required to configure and patch individual servers. Organizations taking advantage of virtualization may benefit from improved incident handling; servers can be reverted to an uninfected state quickly, while the complete state (including RAM) of the compromised guest OS can be saved in a snapshot for later examination.

Machine Learning for Access Control Policy Verification ## Machine Learning for Access Control Policy Verification Access control policy verification ensures that there are no faults within the policy that leak or block access privileges. As a software test, access control policy verification relies on methods such as model proof, data structure, system simulation, and test oracle to verify that the policy logic functions as expected. However, these methods have capability and performance issues related to inaccuracy and complexity limited by applied technologies. For instance, model

proof, test oracle, and data structure methods initially assume that the policy under verification is faultless unless the policy model cannot hold for test cases. Thus, the challenge of the method is to compose test cases that can comprehensively discover all faults. Alternatively, a system simulation method requires translating the policy to a simulated system. The translation between systems may be difficult or impractical to implement if the policy logic is complicated or the number of policy rules is large. To answer these challenges, this internal report (IR) proposes an efficient and straightforward method for access control policy verification by applying a classification algorithm of machine learning, which does not require comprehensive test cases, oracle, or system translation but rather checks the logic of policy rules directly, making it more efficient and feasible compared to traditional methods.

SI.L2-3.14.2 · Malicious Code Protection [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13

250 Unicode), contained within compressed or hidden files, or hidden in files using techniques such as steganography. Malicious code can be inserted into systems in a variety of ways including web accesses, electronic mail, electronic mail attachments, and portable storage devices. Malicious code insertions occur through the exploitation of system vulnerabilities. Malicious code protection mechanisms include anti-virus signature definitions and reputation-based technologies. A variety of technologies and methods exist to limit or eliminate the effects of malicious code. Pervasive configuration management and comprehensive software integrity controls may be effective in preventing execution of unauthorized code. In addition to commercial off-the-shelf software, malicious code may also be present in custom-built software. This could include logic bombs, back doors, and other types of cyber-attacks that could affect organizational missions/business functions. Traditional malicious code protection mechanisms cannot always detect such code. In these situations, organizations rely instead on other safeguards including secure coding practices, configuration management and control, trusted procurement processes, and monitoring technologies to help ensure that software does not perform functions other than the functions intended. NIST SP 800-83 provides guidance on malware incident prevention. FURTHER DISCUSSION A designated location may be a network device such as a firewall or an end user's computer. Malicious code, which can be delivered by a range of means (e.g., email, removable media, or websites), includes the following:

- virus · program designed to damage, steal information, change data, send email, show messages, or any combination of these things;
- spyware · program designed to gather information about a person's activity in secret when they click on a link, usually installed without the person knowing ;
- trojan horse · type of malware made to look like legitimate software and used by cyber criminals to get access to a company's systems; and
- ransomware · type of malware that threatens to publish the victim's data or perpetually block access to it unless a ransom is paid. Use anti-malware tools to stop or lessen the impact of malicious code. Example You are buying a new computer and want to protect your company's information from viruses, spyware, etc. You buy and install anti-malware software [a,b].

Potential Assessment Considerations · Are system components (e.g., workstations, servers, email gateways, mobile devices) for which malicious code protection must be provided identified and documented [a]?

set of emerging standards that support novel forms of IDMSs-and blockchain-based ones in particular-using features and properties provided by blockchain, cryptography, and other related technologies.

They include: | Layer | Description | |-----|-----|

-----| Application |

Applications that interact with a given identity management system through library integrations and API calls | | Implementation | Libraries that integrate the system in third-party applications | | Payload | Message formats, such as JWT, used to exchange data between participants | | Encoding | Methods for encoding data at both the encryption and payload layers | | Encryption | Methods for encrypting messages between participants as well as encrypting the data held by the identifier owner | | DID Authentication | Methods to authenticate a participant using their DID | | Transport | Transport protocols used for sharing data between participants and devices, such as HTTP or QR code | | DID Resolution | DID Resolver used to convert a DID into its corresponding DID document | | DID Operation | Create, Read, Update, and Delete operations for a DID document | | DID Storage | Methods for storing DID Documents and DIDs | | DID Anchor | Networks that serve as medium for DIDs |

DoD responds to an average of 2,000 questions each year and these responses are estimated to take 20 minutes per response. If it takes 20 minutes to respond to each question, it will take 667 hours to respond to questions. At an hourly wage of \$51.16, [13] it will cost the DoD \$34,107 dollars to respond to questions ($\$51.16 \times (.333 \times 2,000) = \$34,107$). Costs to the government are incurred

when a company applies to the DIB CS Program to validate and store POC information and to perform follow-up activities with a company when the information is outdated. The processing time for these activities is estimated to be one hour per company. If 8,000 companies participate in the program and 10% of the companies update information with the program annually the labor cost to the government is expected to be \$450,208 = (8,800 × \$51.16). In addition, there is a cost incurred by the DoD to receive cyber threat information submitted by defense contractors to have it analyzed by cyber threat experts at DC3. By year 9 of the expanded program, it is estimated DC3 will receive 40,000 responses per year, based on the estimate that each participating company elects to submit 5 informational reports (8,000 participants × 5 reports). Each product takes approximately two hours to create and incurs an hourly labor cost of \$51.16 per hour. This equals \$102.32 (2 hours × 51.16) per response. The labor cost to the government is forecasted to be \$4,092,800 annually after 9 years of growth. In addition to processing cyber threat information, the DoD incurs operational and maintenance costs for the system receiving and storing cyber threat information. This system costs the DoD \$5,100,000 annually to maintain (covered under information collection 0704-0489). Benefits

however no attacks are known. NIST would encourage further analysis of all aspects of this scheme.

3.19 FALCON Falcon is a lattice-based signature scheme, based on GPV (Gentry-Peikert-Vaikuntanathan) Gaussian sampling, using the NTRU lattice. The main novelty is a very fast recursive algorithm for Gaussian sampling, using a tree data structure (the "Falcon tree"). The best known attacks against Falcon are based on lattice basis reduction, without significantly exploiting the special structure of the NTRU lattice. Falcon has a formal security proof in the quantum random oracle model. Falcon offers very good performance. However, it is quite complicated to implement, as it relies heavily on the "tower of fields" structure of the number field and requires double-precision floating-point arithmetic. More work is needed to ensure that the signing algorithm is secure against side-channel attacks. ## 3.20 qTESLA qTESLA is a lattice-based signature scheme which uses the assumption that RLWE distributions are indistinguishable from random. The public key in qTESLA is, roughly speaking, a sample of a RLWE distribution. The signer keeps secret information about this sample and uses that information along with a hash function to produce signatures. Signature verification involves some simple arithmetic within the chosen ring, and then the recomputation of a hash function. qTESLA has reasonably good performance parameters that are comparable to the other latticebased signature schemes. The submitters of qTESLA have claimed a tight security proof for the schemes in the quantum random oracle model.

- RISK - VULNERABILITY - EXPOSURE - THE CONDITION OF BEING UNPROTECTED - INFORMATION - KNOWLEDGE OR INTELLIGENCE THAT IS REPRESENTED IN A COMPUTER BY DATA .TEXT, VOICE, OR IMAGE. - BUSINESS CONTROLS - COMBINATION OF ADMINISTRATIVE AND TECHNICAL CONTROLS THAT PROVIDE A REASONABLE ASSURANCE THAT THE ENTERPRISE'S OBJECTIVES WILL BE EXECUTED AS PLANNED.

- 1 . What are Potential Roadblocks to Harmonization? 58 - a. Assurance Approaches 58 - b. Protection Profiles in the FC versus Security Targets and Functionality Classes in the ITSEC 59 - c. International Protection Profiles 59 2. Phase-in to Harmonization 60 - a. What Should be the Steps to Harmonization? 61 - b. How Should Users & Suppliers Proceed during Convergence? 61 - c. How Should Backward Compatibility with National Criteria be Handled? 62 - d. How Does this Work on Common Criteria Relate to ISO SC27? 62 Part of the problem is semantic. The definitions appear to be overloaded. 'Systems' appears to refer to both actual environments of use as well as assemblies of products. The definitions also seem to be dependent on the observers viewpoint A supplier may be a 'system integrator' who employs 'products' to produce a 'system.' But to the integrator's customers, the resultant integration may be a "product" offered for sale. Approximately 25 other individuals were present, including representatives from various US government agencies, other European organizations, and several representatives of muldnational computer product suppliers.

(Comment 46) One comment believes that direct marketing facilities should be explicitly exempted from maintaining records of immediate subsequent recipients. The comment believes that direct marketers that sell their food directly to consumers are functionally no different than brick-and-mortar retail establishments. Moreover, FDA's proposal already explicitly exempts other entities that sell food directly to consumers (farms, some roadside stands, and restaurants). Direct marketers thus should be exempt from another and different mandated recordkeeping protocol. Direct marketers already must meet the recordkeeping requirements of taxing authorities. Adding another enormous, needless recordkeeping requirement for consumers who purchase their food directly would do nothing to achieve the aims of the Bioterrorism Act at the expense of increased costs to marketers

and, thus, their customers. The comment urges FDA to revise the exclusion for retail facilities by explicitly stating that direct marketing facilities are likewise exempt from the one-down requirements of § 1.345. (Response) Neither the proposed nor final rule distinguishes between persons that sell to consumers as direct marketers, including those selling products over the Internet, and other persons selling to consumers from establishments. Therefore, if a direct marketer sells food directly to a consumer, he or she is exempt from establishing and maintaining records of the immediate subsequent recipients of that food. Under § 1.327(e) of this final rule, persons who operate retail food establishments that distribute food to persons who are not consumers are subject to all of the requirements in subpart J of this final rule. However, for retail food establishments, the requirements in § 1.345 to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients that are not consumers applies as to those transactions only, and only to the extent the information is reasonably available. In addition, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements of subpart J of this final rule, except the record access provisions for existing records under §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) For a further discussion of direct sellers' responsibilities under this rulemaking, see response to comment 50 in the following paragraphs.

Integrity 18 Integrity 19 - The unbundling of functional requirements from each other and from assurances. - The creation of protection profiles by assembling pre-defined components and elaborating them to specific product targets. - The explicit separation of documentation, process, and evaluation assurance. - Recognition of Ease of Use, Physical Protection, and Flaw Remediation (this & thought to be especially important to retain) as requirements.

All three small business entities, and up to seven small business subcontractor entities, awarded a contract annually to develop, implement, operate, or maintain a non-cloud FIS will be required to submit a copy of their continuous monitoring strategy for the FIS that demonstrates an ongoing awareness of information security, vulnerabilities, and threats in order to support risk management decisions, and applies the use of automation, wherever possible; protects vulnerability scan data, logs, and telemetry; and applies the guidance of NIST SP 800-137, Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations. A small business will need at least one employee within an information system occupation series (e.g., computer system analyst, information security analyst, system administrator, network architect) to review and submit the continuous monitoring strategy. D. Submit Annual Assessments Of the 140 non-cloud FISs currently being operated or maintained by contractors on behalf of the Government, the Government estimates that approximately 95 percent of those systems are designated as moderate or high FIPS 199 impacts. Applying that percentage to the estimated number of contractors annually awarded a contract to develop, implement, operate, or maintain a non-cloud FIS, it is estimated that 27 contractors (95 percent * 28 contractors), of which 2 are estimated to be small business, will be subject to the annual assessment requirements. These two small business entities, and up to seven small business subcontractor entities, will be awarded a contract with a FIS designated as moderate or high FIPS Publication 199 impact and be required to submit the results of the two annual assessments to the Government. The assessment of the security of the FIS must be an independent assessment that is not conducted by the contractor. The cyber threat hunting and vulnerability assessment may be completed by the contractor. A small business must submit the results of both assessments, including any recommended improvements or risk mitigations identified for the FIS, to the Government. A small business will need at least one employee within an information system occupation series to review and submit the annual assessments to the Government, as well as implement any recommended solutions resulting from the assessments. If an entity chooses to conduct the cyber threat hunting and vulnerability assessment on their own, the entity will need at least one subject matter expert in cyber threat hunting and vulnerability assessment, as well as experience with system assessment, analysis, and audit. This rule proposes to standardize common cybersecurity contractual requirements across Federal agencies. To do so, E.O. 14028

For CMMC Levels 1 and 2, cost estimates are based upon assessment, reporting, and affirmation activities that a contractor or subcontractor will need to take to verify implementation of existing security requirements set forth in FAR clause 52.204-21, effective June 15, 2016, to protect FCI, and DFARS clause 252.204-7012 which required implementation of NIST SP 800-171 requirements not later than December 31, 2017, to protect CUI. As such, cost estimates are not included for an entity

to implement the CMMC Level 1 or 2 security requirements, maintain implementation of these existing security requirements, or remediate a plan of action for unimplemented requirements. For CMMC Level 3, the cost estimates factor in the assessment, reporting, and affirmation activities in addition to estimates for NRE and RE to implement and maintain CMMC Level 3 security requirements. In addition to implementing the CMMC Level 2 security requirements, CMMC Level 3 requires implementing selected security requirement set forth in NIST SP 800-172 Feb2021 as described in §.170.14(c)(4) which are not currently required through other regulations. CMMC Level 3 is expected to apply only to a small subset of defense contractors and subcontractors. The Cost Categories used for each CMMC Level are described: 1. Nonrecurring Engineering Costs: Estimates consist of hardware, software, and the associated labor to implement the same. Costs associated with implementing the requirements set forth in FAR clause 52.204-21 and NIST SP 800-171 R2 are assumed to have been already implemented and, therefore, are not accounted for in this cost estimate. As such, these costs only appear in CMMC Level 3. If nonrecurring engineering costs are referenced, they are only accounted for as a one-time occurrence and are reflected in the year of the initial assessment. 2. Recurring Engineering Costs: Estimates consist of annually recurring fees and associated labor for technology refresh. Costs associated with implementing the requirements set forth in FAR clause 52.204-21 and NIST SP 800-171 R2 are assumed to have been already implemented and, therefore, are not accounted for in this cost estimate. As such, these costs only appear in CMMC Level 3. 3. Assessment Costs: Estimates consist of activities for pre-assessment preparations (which includes gathering and/or developing evidence that the assessment objectives for each requirement have been satisfied), conducting and/or participating in the actual assessment, and completion of any post-assessment work. Assessment costs are represented by notional phases. Assessment costs assume the OSA passes the assessment on the first attempt (conditional-with an allowable POA&M or final). Each phase includes an estimate of hours to conduct the assessment activities including: (a) Labor hour estimates for a company (and any ESP support) to prepare for and participate in the assessment. (printed page 83180) (b) C3PAO cost estimates for companies pursuing a certification

The record retention periods for nontransporters have been changed to: (1) 6 months for food for which a significant risk or spoilage, loss of value, or loss of palatability occurs within 60 days after the date you receive or release the food; (2) 1 year for food for which a significant risk of spoilage, loss of value, or loss of palatability occurs only after a minimum of 60 days, but within 6 months, after the date you receive or release the food; and (3) 2 years for food for which a significant risk of spoilage, loss of value, or loss of palatability does not occur sooner than 6 months after the date you receive or release the food, including foods preserved by freezing, dehydrating, or being placed in a hermetically sealed container. The record retention periods for transporters (or specified persons who agree to establish and maintain required records under agreements with transporters) have been changed to 6 months for any food having a significant risk or spoilage, loss of value, or loss of palatability within 60 days after the date the food is received or released and 1 year for any food having a significant risk or spoilage, loss of value, or loss of palatability only after a minimum of 60 days after the date the food is received or released. The record availability requirements have been changed from 4 hours/8 hours to ·as soon as possible, not to exceed 24 hours from the time of receipt of the official request.· The compliance date for these regulations has changed to December 9, 2005. Small businesses have June 9, 2005, of this final rule to come into compliance with these regulations, and very small businesses have December 11, 2006, of this final rule to come into compliance with these regulations. The qualifying language ·food intended for consumption in the United States· has been removed from this final rule to ensure that all persons that manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States that is intended for consumption are subject to this final rule unless otherwise exempt. III. Comments on the Proposed Rule FDA received approximately 212 timely submissions in response to the proposed rule, which raised approximately 220 major issues. To make it easier to identify comments and FDA's responses to the comments, the word ·Comment· will appear in parentheses before the description of the comment, and the word ·Response· will appear in parentheses before FDA's response. FDA has also numbered each comment to make it easier to identify a particular comment. The number assigned to each comment is purely for organizational purposes and does not signify the comment's value or importance or the order in which it was submitted. A. General Comments

The proposed requirement to obtain verification of compliance with technical safeguards also would apply to business associates with respect to their subcontractors. However, we believe that a much smaller number of business associates rely on subcontractors compared to the number of covered

entities that rely on business associates to conduct activities on their behalf. Thus, we estimate that, on average, business associates would need 5 minutes annually to obtain verification from their subcontractors that the subcontractors have complied with technical safeguards as required by the Security Rule. The estimate includes only the time needed for business associates to send a mass email to subcontractors because we have already addressed the burden on business associates of producing the verification in the previous section and that estimate includes burdens on subcontractors. The high estimate for this activity would be an average of 15 minutes per business associate, and a low estimate would be for business associates to 2 minutes on this activity. At the wage rate of an information security analyst, this would add estimated total costs for business associates of \$9,995,000 [= 1,000,000 business associates × 0.083 hours × \$119.94], with a high estimate of \$29,985,000 [= 1,000,000 business associates × .25 hours × \$119.94].

d. Cost Related to Notification of Termination or Change of Workforce Members' Access to ePHI The Department estimates that regulated entities are likely to incur additional costs to implement a process to notify other regulated entities when a workforce member's access to ePHI is terminated or changed under proposed 45 CFR 164.308(a)(9)(ii). This estimate assumes that notifications will take an average of 1 hour annually per regulated entity. This results in new estimated costs totaling \$84,021,860 [= 1,822,600 regulated entities × 1 hour × \$46.10]. [962]

e. Cost Related to Regulated Entities Deploying Multi-Factor Authentication The Department estimates that, on average, regulated entities would have an information security analyst spend 1.5 hours deploying MFA, as specifically required under proposed 45 CFR 164.312(f)(2)(ii)

, and which is required to be kept secret in the interest of national defense or foreign policy. Exempted portions of this system may also contain information considered relevant and necessary to make a determination as to qualifications, eligibility, or suitability for access to classified information, and which was obtained by providing an express or implied promise to the source that his or her identity would not be revealed to the subject of the record. Exempted portions of this system may also contain information collected and maintained in connection with providing protective services to the President and other individuals protected pursuant to 18 U.S.C. 3056. Exempted portions of this system may also contain investigative records compiled for law enforcement purposes, the disclosure of which could reveal the identity of sources who provide information under an express or implied promise of confidentiality, compromise investigative techniques and procedures, jeopardize the life or physical safety of law-enforcement personnel, or otherwise interfere with enforcement proceedings or adjudications. (2) System identifier and name. N01131-1, Officer Selection and Appointment System. (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958, as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (C) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6), if the disclosure would compromise the objectivity or fairness of the test or examination process. (D) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7), but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (E) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(1), (e)(4)(G) through (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(1), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Granting individuals access to portions of this system of records could result in the disclosure of classified material, or the identification of sources who provided information to the government under an express or implied promise of confidentiality. Material will be screened to permit access to unclassified material and to information that does not disclose the identity of a confidential source. (3) System identifier and name. N01133-2, Recruiting Enlisted Selection System. (i) Exemption.

officer to delay payments and requiring in any case the burden on data collecting, validating, etc. on both the Supplier and the Buyer. This respondent also raised the issue of how data on incurred costs will be stored and managed and who will have access to the database created with these costs. The respondent questioned how the contracting officer will be able to find applicable previous cases. Response: In accordance with FAR 15.403-3(b), the contracting officer may require data other than certified cost or pricing data to support a determination of a fair and reasonable price.

In negotiations, one way to ensure a fair and reasonable price is through the use of various price analysis techniques and procedures to include a comparison of proposed prices to historical prices (i.e., incurred costs) paid for the same or similar items. Use of prior incurred costs in negotiations are not meant to create never-ending discussions, but to facilitate negotiation of a fair and reasonable price for all concerned parties. The requirement to provide incurred cost data is not a new requirement, and this data has been available for use in negotiations for many years. As with any sensitive information, all incurred cost data will be maintained in the official contract file for official use only. There is no intent to create a new database.

5. Requirement for Title Comment: Two respondents addressed the requirement in FAR 52.232-32(f) that the Government take title to work in progress immediately upon the date of the receipt of a PBP payment. Two respondents stated that the requirement for title conflicts with 10 U.S.C. 2307(b)(4)(A), which states that in order to receive performance-based payments, a contractor's accounting system shall be in compliance with GAAP, and there shall be no requirement for a contractor to develop Government-unique accounting systems or practices as a prerequisite for agreeing to receive performance-based payments. According to the respondents, because many GAAP-compliant accounting systems are unable to isolate the work in process associated with a particular unit from the rest of the supply chain until delivery, requiring a contractor to deliver title to such goods is therefore de facto requirement for a Government-unique accounting system. One respondent also stated that requiring title to work in progress immediately upon receipt of a PBP payment represents bad policy. According to the respondent, allowing contractors to aggregate component purchases across multiple contracts can reduce costs and improve schedules. To maximize this flexibility, contractors need to be able to reallocate common parts between contracts based on customer needs and vendor availability. This benefits DoD. Two respondents pointed out that DoD has existing flexibility in 10 U.S.C. 2307(d)

While the Department values the input provided by small business stakeholders and understands the desire for flexibilities, including the use of POA&Ms during the initial implementation phase, it must carefully balance multiple factors to ensure the effectiveness and integrity of the CMMC Program.

SBA Comment 6: Advocacy's chief concerns surround a lack of clarity on key aspects of the proposed rule. Advocacy requests clarification from DoD as to how to create enclaves within businesses. Encouraging the use of ESPs and incentivizing large prime contractors to keep all subcontractors from being subject to high levels of cybersecurity will be key in keeping small businesses engaged in DoD contracting. Guidance documents for small businesses (especially aimed at the smallest of small businesses) and ESPs will create an easier ramp for small business compliance. Advocacy requests clarity from DoD regarding the role of C3PAOs and encourages the DoD to ensure small businesses can obtain certification from C3PAOs in a timely manner. Further, the DoD should clarify the enforcement and procedural repercussions for a failure to meet various CMMC levels. Lastly, the DoD (printed page 83204) should set achievable goals as CMMC is implemented, ensuring that current small businesses contracting with the agency can continue work with the government while ensuring our nation's defense.

DoD Response: The DoD acknowledges the SBA advocacy chief's concerns and will make additional training resources available following finalization of this rule. The DoD deems that the level of detail on the topics identified is appropriate for codification in the 32 CFR part 170 CMMC Program rule. The DoD will resume outreach efforts with the aim of promoting CMMC familiarization among small businesses once the rule is final and effective and any constraints on such engagements no longer apply. However, DoD caveats that providing any specific instructions for configuring corporate information systems into enclaves is beyond the guidance that DoD intends to provide, as such decisions are unique to each company. The role of C3PAOs is thoroughly described in § 170.9 CMMC Third-Party Assessment Organizations (C3PAOs) and in the supplemental documents. In terms of enforcement, since CMMC will be implemented as a pre-award requirement, the repercussions of failure to meet CMMC requirements will include failure to be selected for contract award, or standard contractual and other remedies for failure to timely and satisfactorily close-out a POA&M and meet or maintain the contractual CMMC requirements.

As described in Section 5.2, the overall security strength of a digital signature is limited by the collision resistance strength of the hash function. However, when using the randomized hashing technique specified in SP 800-106 [SP 800-106], a randomized hash function may support a higher level of security with respect to a particular potential vulnerability, offering enhanced protection to a message signer against a collision attack by a malicious message preparer who formulates the message to be signed, but does not actually sign the message.

(1) The Secretary of Homeland Security has the authority to determine the eligibility for personnel security clearances and to administer the sharing of relevant classified NSI with certain private sectors or non-federal partners for the purpose of furthering cybersecurity information sharing among critical infrastructure partners pursuant to E.O. 13691 . (2) DHS provides security oversight and assumes security responsibilities similar to those of an FSO, unless otherwise provided in this section. Participating entities will cooperate with DHS security officials to ensure the entity is in compliance with requirements in this rule. § 117.23 Supplement to this rule: Security Requirements for Alternative Compensatory Control Measures (ACCM), Special Access Programs (SAPs), Sensitive Compartmented Information (SCI), Restricted Data (RD), Formerly Restricted Data (FRD), Transclassified Foreign Nuclear Information (TFNI), and NNPI. (a) General. Given the sensitive nature of Alternative Compensatory Control Measures (ACCM), SAPs, SCI, RD, FRD, TFNI, and NNPI, the security requirements prescribed in this section exceed baseline standards for this rule and must be applied, as applicable, through specific contract requirements. (1) Compliance. The contractor will comply with the security measures reflected in this section and other documents specifically referenced, when applied by the GCA or designee as part of a contract. Acceptance of the contract security measures is a prerequisite to any negotiations leading to program participation and an area accreditation (e.g., an SCI facility or SAP facility accreditation). (2) CSA-imposed higher standards. In some cases, security or sensitive factors of a CSA-created program may require security measures that exceed the standards of this section. In such cases, the CSA-imposed higher standards specifically detailed in the contract or conveyed through other applicable directives will be binding on USG and contractor participants. In cases of doubt over the specific provisions, the contractor should consult the program security officer and the contracting officer before taking any action or expending program-related funds. In cases of extreme emergencies requiring immediate attention, the action taken should protect the USG's interest and the security of the program from loss or compromise. (3) Waivers. Every effort will be made to avoid waivers to established standards unless they are in the best interest of the USG. In those cases where waivers are deemed necessary, a request will be submitted in accordance with the procedures established by the CSA. (b) Intelligence information.

AU.L2-3.3.6 · Reduction & Reporting CMMC Assessment Guide · Level 2 | Version 2.13 84 FURTHER DISCUSSION Raw audit log data is difficult to review, analyze, and report because of the volume of data. Audit record reduction is an automated process that interprets raw audit log data and extracts meaningful and relevant information without altering the original logs. An example of log reduction for files to be analyzed would be the removal of details associated with nightly backups. Report generation on reduced log information allows you to create succinct customized reports without the need to burden the reader with unimportant information. In addition, the security-relevant audit information must be made available to personnel on demand for immediate review, analysis, reporting, and event investigation support. Performing audit log reduction and providing on-demand reports may allow the analyst to take mitigating action before an adversary completes its malicious actions. Example You are in charge of IT operations in a company that processes CUI. You are responsible for providing audit record reduction and report generation capability. To support this function, you deploy an open-source solution that will collect and analyze data for signs of anomalies. The solution queries your central log repository to extract relevant data and provide you with a concise and comprehensive view for further analysis to identify potentially malicious activity [a]. In addition to creating on-demand data sets for analysis, you create customized reports explaining the contents of the data set [b]. Potential Assessment Considerations · Does the system support on-demand audit review, analysis, and reporting requirements and after-the-fact security investigations [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.3.6

There is no CMMC Level 4. The CMMC 2.0 framework established by 32 CFR Part 170 defines three levels: - Level 1: 15 basic safeguarding requirements from FAR 52.204-21 (self-assessment) - Level 2: 110 security requirements from NIST SP 800-171 Rev 2/Rev 3 (self-assessment or C3PAO certification) - Level 3: Enhanced requirements from NIST SP 800-172 (government-led assessment by DIBCAC) The original CMMC 1.0 model had five levels, but CMMC 2.0 consolidated these into three. Levels 4 and 5 from the original model no longer exist.

However, the HITECH Act amendment did not require the Secretary to accept a regulated entity's implementation of recognized security practices as an alternative to compliance with the Security Rule, nor did it provide that such implementation was sufficient to meet the security objectives of HIPAA or the HITECH Act. Accordingly, it is appropriate for the Department to develop and adopt its

own standards to meet the statutory objective of ensuring the security of ePHI. The standards and implementation specifications proposed herein take into consideration not only those promulgated by NIST, but also guidelines, best practices, methodologies, processes, and procedures published by CISA, the HHS 405(d) program, CMS, State governments, and others. The proposals also enable regulated entities to adopt security measures that ensure the confidentiality, integrity, and availability of ePHI; protect against any reasonably anticipated threats or hazards to the security or integrity of ePHI and unauthorized uses or disclosures of such ePHI; ensure compliance with the Security Rule by the workforce members of regulated entities, while also taking into account the technical capabilities of record systems used to maintain ePHI; the costs of such measures; the need for training users who have access to ePHI; the value of audit trails in computerized record systems; and the needs and capabilities of small and rural health care providers. The Department has consulted with and relied on the recommendations of NCVHS in the formulation of this proposed rule [331] and intends to continue to engage in these consultations before finalizing the rule. [332] We also expect to consult with the National Uniform Billing Committee, the National Uniform Claim Committee, the Workgroup for Electronic Data Interchange, and the American Dental Association before finalizing this rule, as required by section 1172(c)(3)(A)(ii) of HIPAA. [333]

IV. Section-by-Section Description of the Proposed Amendments to the Security Rule

means a document that identifies tasks needing to be accomplished. It details resources required to accomplish the elements of the plan, any milestones in meeting the tasks, and scheduled completion dates for the milestones, as defined in NIST SP 800-115 Sept2008 (incorporated by reference, see §.170.2). Prime Contractor is defined in 48 CFR 3.502-1 . Process, store, or transmit means data can be used by an asset (e.g., accessed, entered, edited, generated, manipulated, or printed); data is inactive or at rest on an asset (e.g., located on electronic media, in system component memory, or in physical format such as paper documents); or data is being transferred from one asset to another asset (e.g., data in transit using physical or digital transport methods). (CMMC-custom term) Restricted Information Systems means systems (and associated IT components comprising the system) that are configured based on government requirements (e.g., connected to something that was required to support a functional requirement) and are used to support a contract (e.g., fielded systems, obsolete systems, and product deliverable replicas). (CMMC-custom term) Risk means a measure of the extent to which an entity is threatened by a potential circumstance or event, and is typically a function of: (i) The adverse impacts that would arise if the circumstance or event occurs; and (ii) The likelihood of occurrence, as defined in NIST SP 800-53 R5 (incorporated by reference, see §.170.2). Risk Assessment means the process of identifying risks to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the Nation, resulting from the operation of a system. Risk Assessment is part of risk management, incorporates threat and vulnerability analyses, and considers mitigations provided by security controls planned or in place. Synonymous with risk analysis, as defined in NIST SP 800-39 Mar2011 (incorporated by reference, see §.170.2). Security Protection Assets (SPA) means assets providing security functions or capabilities for the OSA's CMMC Assessment Scope. (CMMC-custom term) Security Protection Data (SPD) means data stored or processed by Security Protection Assets (SPA) that are used to protect an OSC's assessed environment. SPD is security relevant information and includes but is not limited to: configuration data required to operate an SPA, log files generated by or ingested by an SPA, data related to the configuration or vulnerability status of in-scope assets, and passwords that grant access to the in-scope environment. (CMMC-custom term) Specialized Assets means types of assets considered specialized assets for CMMC: Government Furnished Equipment, Internet of Things (IoT) or Industrial Internet of Things (IIoT), Operational Technology (OT), Restricted Information Systems, and Test Equipment. (CMMC-custom term) Subcontractor is defined in 48 CFR 3.502-1 . Supervisory Control and Data Acquisition (SCADA)

Consistent with our proposals to require that regulated entities maintain their technical controls, we also propose to require a regulated entity to review and test the effectiveness of its technical controls for guarding against unauthorized access to ePHI that is being transmitted over an electronic communications network. We propose that such review and testing occur at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify such technical controls as reasonable and appropriate. The Department also proposes to remove the implementation specification for integrity controls at 45 CFR 164.312(e)(2)(i) because these requirements are incorporated in the standard for integrity at proposed 45 CFR 164.312(e) , discussed above. A regulated entity would continue to be required to review the current methods used

to transmit ePHI and then deploy appropriate solutions to protect ePHI from improper alteration or destruction. [791] i. Section 164.312(h)(1)-Standard: Vulnerability Management Hackers can penetrate a regulated entity's network and gain access to ePHI by exploiting publicly known vulnerabilities. [792] Exploitable vulnerabilities can exist in many parts of the technology infrastructure of a regulated entity's relevant electronic information systems (e.g., server, desktop, and mobile device operating systems; application, database, and web software; router, firewall, and other device firmware). [793] A regulated entity can identify technical vulnerabilities in multiple, complementary ways, including: Subscribing to CISA alerts [794] and bulletins. [795] Subscribing to alerts from the HHS Health Sector Cybersecurity Coordination Center. [796] Participating in an information sharing and analysis center (ISAC) or information sharing and analysis organization (ISAO). Implementing a vulnerability management program that includes using a vulnerability scanner to detect vulnerabilities such as obsolete software and missing patches. Periodically conducting penetration tests to identify weaknesses that could be exploited by an attacker. Additionally, CISA has compiled a database of free cybersecurity services and tools, some provided directly by CISA and others provided by private and public sector organizations. [797] For example, public and private critical infrastructure organizations may avail themselves of CISA's Cyber Hygiene Services. [798] These services are available at no cost to such organizations and can help regulated entities reduce their risk level, identify vulnerabilities that could otherwise go unmanaged and increase the accuracy and effectiveness of their response activities, among other benefits, putting them in a better place to make risk-informed decisions. CISA's Cyber Hygiene Services include both vulnerability scanning and web application scanning. CISA also has compiled a specific suite of tools and services for high-risk communities. [799]

DoD agrees with the need for added clarity around internal ESPs and the rule was modified to remove the term internal ESP. An ESP that provides staff augmentation, where the OSA provides all processes, technology, and facilities, does not need CMMC assessment. Alternatively, an ESP can be part of the same organizational structure but still be external to the OSA, such as a centralized SOC or NOC which supports multiple business units. The CMMC requirements apply and are based on whether the ESP provides cloud services and whether the ESP processes, stores, or transmits CUI on their systems. The OSA's contractual rights with its CSP are beyond the scope of this rule. The rule states requirements for the OSA, not the ESP. The rule requires OSAs that process, store, or transmit FCI and CUI to protect that data. If those OSAs elect to use an ESP, and that ESP processes, stores, or transmits FCI or CUI from the OSA, then the OSA must require that the ESP protect the FCI and CUI and the ESP will be assessed as part of the OSA's assessment or require FedRAMP Moderate or equivalent. Specifically for Level 3, if an OSC is seeking Level 3 certification and uses an ESP that is not a CSP and that DOES process, store, or transmit CUI, then the ESP will need to be assessed by DIBCAC (printed page 83137) against the same Level 3 requirements as the OSC as part of the OSC's assessment unless the ESP voluntarily seeks a DIBCAC Assessment. If an OSC is seeking Level 3 certification and uses an ESP that DOES NOT process, store, or transmit CUI, then the ESP will NOT need to be assessed by DIBCAC against the same Level 3 requirements as the OSC. ESPs provide a service that meets the requirements specified by the OSA, and therefore ESPs are not subcontractors on a DoD contract and are not bound by subcontractor flow down requirements. d. Assessment of ESPs Comment: There were multiple comments regarding the assessment of an ESP. One comment recommends the rule be revised to identify the specific assessment requirements that would be considered NOT MET by the OSA when using a non-compliant ESP, and to further require C3PAOs to validate the OSCs use of compliant ESPs during a CMMC Level 2 assessment. One comment asks if an ESP, when assessed, will require a CAGE code, and enter scores into SPRS. Another comment asked whether CMMC certification would be required when offering full IT management and online storage, including CUI, if the MSP policies prevent employees from accessing customer data.

AT.L2-3.2.2 · Role-Based Training CMMC Assessment Guide · Level 2 | Version 2.13 69 validation, security assessors, and other personnel having access to system-level software, security-related technical training specifically tailored for their assigned duties. Comprehensive role-based training addresses management, operational, and technical roles and responsibilities covering physical, personnel, and technical controls. Such training can include policies, procedures, tools, and artifacts for the security roles defined. Organizations also provide the training necessary for individuals to carry out their responsibilities related to operations and supply chain security within the context of organizational information security programs. NIST SP 800

-181 provides guidance on role-based information security training in the workplace. SP 800-161 provides guidance on supply chain risk management. FURTHER DISCUSSION Training imparts skills and knowledge to enable staff to perform a specific job function. Training should be available to all employees for all organizational roles to accommodate role changes without being constrained by the training schedule. Awareness training and role-based training are different. Awareness training provides general security training to influence user behavior and is covered by AT.L2-3.2.1. This requirement, AT.L2-3.2.2, covers role-based training that focuses on the knowledge, skills, and abilities needed to complete a specific job. Role-based training may include awareness topics specific to individual roles such as ensuring systems administrators understand the risk associated with using an administrative account. Example Your company upgraded the firewall to a newer, more advanced system to protect the CUI it stores. You have been identified as an employee who needs training on the new device [a,b,c]. This will enable you to use the firewall effectively and efficiently. Your company considered training resources when it planned for the upgrade and ensured that training funds were available as part of the upgrade project [c]. Potential Assessment Considerations · Are the duties, roles, and responsibilities that impact, directly or indirectly, the information security of the company or its systems defined and documented [a]? · Do information security-related tasks have accountable owners, and is a strictly limited group of individuals assigned to perform them [b]? · Are personnel who are assigned information security-related duties, roles, and responsibilities trained on those responsibilities, including the security requirements unique or inherent to their roles or responsibilities [c]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.2.2

Technology professionals who want to implement an approach like this can make use of NIST SP 180010C: How-To Guides. It provides specific product installation, configuration, and integration instructions for building the example implementation, allowing you to replicate all or parts of this project. NIST Cybersecurity Practice Guides (Special Publication 1800 series) target specific cybersecurity challenges in the public and private sectors. They are practical, user-friendly guides that facilitate the adoption of standards-based approaches to cybersecurity. They show members of the information security community how to implement example solutions that help them align more easily with relevant standards and best practices, and provide users with the materials lists, configuration files, and other information they need to implement a similar approach. integrity-checking, change control management, and user authentication and authorization. The solution was tested in two distinct lab settings: a discrete manufacturing workcell, which represents an assembly line production, and a continuous process control system (PCS), which represents chemical manufacturing industries.

From the NIST SP 800-172 Rev 3 Final Public Draft: Organization-Defined Parameters 3161 This appendix lists the ODPs that are included in the enhanced security requirements in Sec. 3. The ODPs are listed sequentially by requirement family, beginning with the first requirement containing an ODP in the Access Control family and ending with the last requirement containing an ODP in the Supply Chain Risk Management family. Embedded ODPs are listed as a single entry in the table. Table 4. Organization-defined parameters ENHANCED SECURITY REQUIREMENT ORGANIZATION-DEFINED PARAMETER 03.01.01E [Assignment: organization-defined privileged commands and/or other organization-defined actions] 03.01.02E [Assignment: organization-defined restrictions] 03.01.04E [Assignment: organization-defined account and/or account type] 03.01.04E [Assi

AC.L2-3.1.2 · Transaction & Function Control CMMC Assessment Guide · Level 2 | Version 2.13 18 FURTHER DISCUSSION Limit users to only the information systems, roles, or applications they are permitted to use and are needed for their roles and responsibilities. Limit access to applications and data based on the authorized users' roles and responsibilities. Common types of functions a user can be assigned are create, read, update, and delete. Example Your team manages DoD contracts for your company. Members of your team need to access the contract information to perform their work properly. Because some of that data contains CUI, you work with IT to set up your group's systems so that users can be assigned access based on their specific roles [a]. Each role limits whether an employee has read-access or create/read/delete/update-access [b]. Implementing this access control restricts access to CUI information unless specifically authorized. Potential Assessment Considerations · Are access control lists used to limit access to applications and data based on role and/or identity [a]? · Is access for authorized users restricted to those parts of the system they are explicitly permitted to use (e.g., a person who only performs word-processing cannot access developer tools) [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.1.2 · FAR Clause

(b) Restaurants are excluded from all of the requirements in this subpart. A restaurant/retail facility is excluded from all of the requirements in this subpart if its sales of food it prepares and sells to consumers for immediate consumption are more than 90 percent of its total food sales.

(c) Fishing vessels, including those that not only harvest and transport fish but also engage in practices such as heading, eviscerating, or freezing intended solely to prepare fish for holding on board a harvest vessel, are excluded from all of the requirements in this subpart, except §§ 1.361 and 1.363. However, those fishing vessels otherwise engaged in processing fish are subject to all of the requirements in this subpart. For the purposes of this section, *processing* means handling, storing, preparing, shucking, changing into different market forms, manufacturing, preserving, packing, labeling, dockside unloading, holding or heading, eviscerating, or freezing other than solely to prepare fish for holding on board a harvest vessel.

(d) Persons who distribute food directly to consumers are excluded from the requirements in § 1.345 to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients as to those transactions. The term *consumers* does not include businesses. (printed page 71652)

(e) Persons who operate retail food establishments that distribute food to persons who are not consumers are subject to all of the requirements in this subpart. However, the requirements in § 1.345 to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients that are not consumers applies as to those transactions only to the extent the information is reasonably available.

(1) For purposes of this section, retail food establishment is defined to mean an establishment that sells food products directly to consumers as its primary function. The term *consumers* does not include businesses.

(2) A retail food establishment may manufacture/process, pack, or hold food if the establishment's primary function is to sell from that establishment food, including food that it manufactures/processes, packs, or holds, directly to consumers.

(3) A retail food establishment's primary function is to sell food directly to consumers if the annual monetary value of sales of food products directly to consumers exceeds the annual monetary value of sales of food products to all other buyers.

(4) A *retail food establishment* includes grocery stores, convenience stores, and vending machine locations.

(f) Retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements in this subpart, except §§ 1.361 and 1.363. The exclusion is based on the number of full-time equivalent employees at each retail food establishment and not the entire business, which may own numerous retail stores.

) Contact DSS to determine an alternative method to the proposed SSA when the GCA chooses not to issue a NID (e.g., a contract modification, a contract novation, or a PA or VTA authorized by the Program Executive Officer). (5) Notify DSS in writing when NSA, ODNI, or DOE renders a decision on a proposed NID involving access to COMSEC, SCI, or RD, respectively. A GCA's NID decision is not final until NSA, ODNI, or DOE, as applicable, respond regarding access to COMSEC, SCI, or RD. (6)

) When denying a NID, retain documentation explaining the rationale for the decision. (6)

Government Security Committee (GSC). (i) Under a VTA, PA, SSA, or SCA, DSS will ensure that the contractor establishes a permanent committee of its Board of Directors or similar body known as the GSC. (A) The members of the GSC are required in accordance with DoD 5220.22-M to ensure that the contractor maintains policies and procedures to safeguard classified and export controlled information entrusted to it, and that violations of those policies and procedures are promptly investigated and reported to the appropriate authority when it has been determined that a violation has occurred. (B) The GSC will also take the necessary steps in accordance with DoD 5220.22-M to ensure that the contractor complies with U.S. export control laws and regulations and does not take action deemed adverse to performance on classified contracts. This will include the appointment of a Technology Control Officer and the establishment of Technology Control Plan (TCP). (ii) DSS will provide oversight, advice, and assistance to GSCs. These measures are intended to ensure that GSCs:

(A) Maintain policies and procedures to safeguard classified information and export-controlled unclassified information in the possession of the contractor with no adverse impact on the performance of classified contracts. (B) Verify contractor compliance with the DD Form 441 or its successor form, the FOCI mitigation agreement or negation agreement and related documents, contract security requirements, USG export control laws, and the NISP. (printed page 19476) (iii) In the case of an SSA, DSS will ensure that the number of outside directors exceeds the number of inside directors, as defined in DoD 5220.22-M. DSS will determine if the outside directors should be a majority of the Board of Directors based on an assessment of security risk factors pertaining to the contractor's access to classified information. In the case of an SCA, DSS will require the

contractor to have at least one outside director, but may require more than one outside director based on an assessment of security risk factors.

(5) Requesters who seek records about themselves contained in a Privacy Act system of records (1st party requesters) and who cite or imply only the Privacy Act, will have their request processed under the provisions of both the PA and the Freedom of Information Act. If the information requested is not contained in a Privacy Act system of records or is not about the requester, the individual's request will be processed under the provisions of the Freedom of Information Act only, and the Freedom of Information Act processing requirements/time lines will apply. (6) Third party information. (i) Third party information contained in a Privacy Act system of records that does not pertain to the requester, such as SSN, home addresses, and other purely personal information that is not about the requester, will be processed under the provisions of Freedom of Information Act only. Third party information that is not about the requester is not subject to the Privacy Act's first party access provision. (ii) Information about the relationship between the first party requester and a third party is normally disclosed as pertaining to the first party requester. Consult your servicing Staff Judge Advocate if there is a question about the release of third party information to a first party requester. (7) If an individual requests information about them contained in a Privacy Act system of records, the individual may be denied the information only if the information is exempt under both the PA and the Freedom of Information Act. Both PA and Freedom of Information Act exemptions will be cited in the denial letter and appeals will be processed in accordance with both Acts. (8) Each time a first party requester cites or implies the PA, perform this analysis: (i) Is the request from a United States living citizen or an alien lawfully admitted for permanent residence? (ii) Is the individual requesting an agency record? (iii) Are the records within a PA system of records that are filed and retrieved by an individual's name or other personal identifier? (If the answer is 'yes' to all of these questions, then the records should be processed under the 'Privacy Act') and (iv) Does the information requested pertain exclusively to the requester? (A) If yes, no further consideration of Freedom of Information Act exemptions required. Release all information unless a PA exemption authorizes withholding. (B) If no, process the information that is not about the requester under the Freedom of Information Act and withhold only if a proper Freedom of Information Act exemption applies. (h) Functional requests.

AC.L2-3.1.6 · Non-Privileged Account Use CMMC Assessment Guide · Level 2 | Version 2.13 27
AC.L2-3.1.6 · NON-PRIVILEGED ACCOUNT USE Use non-privileged accounts or roles when accessing nonsecurity functions. ASSESSMENT OBJECTIVES [NIST SP 800-171A]21 Determine if: [a] nonsecurity functions are identified; and [b] users are required to use non-privileged accounts or roles when accessing nonsecurity functions. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]21 Examine [SELECT FROM: Access control policy; procedures addressing least privilege; system security plan; list of system-generated security functions assigned to system accounts or roles; system configuration settings and associated documentation; system audit logs and records; other relevant documents or records]. Interview [SELECT FROM: Personnel with responsibilities for defining least privileges necessary to accomplish specified organizational tasks; personnel with information security responsibilities; system or network administrators]. Test [SELECT FROM: Mechanisms implementing least privilege functions]. DISCUSSION [NIST SP 800-171 REV. 2]22 This requirement limits exposure when operating from within privileged accounts or roles. The inclusion of roles addresses situations where organizations implement access control policies such as role-based access control and where a change of role provides the same degree of assurance in the change of access authorizations for the user and all processes acting on behalf of the user as would be provided by a change between a privileged and non-privileged account. FURTHER DISCUSSION A user with a privileged account can perform more tasks and access more information than a person with a non-privileged account. Tasks (including unauthorized tasks orchestrated by attackers) performed when using the privileged account can have a greater impact on the 21 NIST SP 800-171A, p. 11. 22 NIST SP 800-171 Rev. 2, p. 12.

) to extend until August 24, 2022, the implementation date for those contractors under DoD security cognizance to report and obtain pre-approval of unofficial foreign travel to the DoD. The technical amendment was effective on August 19, 2021 and was done to allow DoD to make modifications to its information technology (IT) systems. The technical amendment addressed comments from regulated parties on the burdensome nature of submitting individual foreign travel reports for those contractors under DoD security cognizance. The technical amendment allowed DoD more time to make the necessary changes to the IT system for multiple foreign travel reports in a single submission. This

proposed rule addresses the comments received on the final rule published in December 2020 and further amends the 32 CFR 117 to make the following changes as discussed below. Discussion of Comments and Changes The December 21, 2020 final rule received nine sets of public comments from five individuals who provided 11 comments, two companies that provided 41 comments, an industry representative organization that provided 28 comments, and a law firm that provided four comments, for a total of 84 comments. Clarification on Procedures The vast majority of the comments related to a request for clarification on procedures for those contractors under DoD security cognizance. Many of the comments did not result in a change to the rule because they related to procedures that a NISP CSA would provide to supplement unique CSA mission requirements. For contractors under DoD security cognizance, DoD provides unique CSA mission guidance via industrial security letters (ISLs) when applicable. ISLs are published on the Defense Counterintelligence and Security Agency (DCSA) website (<https://www.dcsa.mil/>) and will address the comments received and re-issue previous NISPOM ISLs, as needed. Previous ISLs were tied to the content of the NISPOM when it was a DoD manual. Some of the guidance contained in prior ISLs has been incorporated into the rule and is no longer needed. Those ISLs that are still needed in order to provide further guidance to those contractors under DoD security cognizance will be re-issued in accordance with the rule. Comments Related to SEAD 3 Implementation Many comments were received on § 117.8, relating to implementation of SEAD 3, Reporting Requirements for Personnel with Access to Classified Information or Who Hold a Sensitive Position,

One person suggested that DoD's Zero-Trust approach would provide a higher level of security for CUI data than the CMMC program. One commenter stated the Department should develop clear, flexible guidelines and alternative pathways for global companies to achieve CMMC compliance without relying on enclave architectures and recommended that this approach rely on Zero Trust principals. One comment noted that under FAR clause 52.204-21, FCI does not include simple transactional information (STI) and asked if certain data would be considered STI and therefore not subject to CMMC. One comment stated that conflicting regulatory guidance exists between the content of E.O. 15028 , NIST SP 800-218, NIST SP 800-171 R2, and NIST SP 800-171 Revision 3. Response: One comment lacked clarity and failed to clearly articulate (printed page 83107) any relevance to the content of this rule, so no response can be provided. SPRS will be used for reporting CMMC Status of all contractors, regardless of which service issued the contract. Publication of this rule follows completion of OMB's formal rulemaking process, which includes both DoD internal coordination (including the USD(A&S) and USD(R&E)) and Interagency coordination. CMMC is consistent with Section 3.4 of DoDI 8582.01, Validation and Compliance. CMMC does not specify the content and format of plans of action beyond what is specified in NIST SP 800-171 R2, which is required under DoDI 8582.01. Clinger Cohen Act requirements, which apply to DoD's IT investments, are not relevant to CMMC Program requirements, which apply to contractor-owned information systems. The classification marking of existing DoD documentation is beyond the scope of this rule, as is engagement with INCOSE and ISO/IEC certification organizations. Executive Orders state mandatory requirements for the Executive Branch and have the effect of law. E.O. 14028 --Improving the Nation's Cybersecurity- (issued May 12, 2021) requires agencies to enhance cybersecurity and software supply chain integrity. NIST SP 800-171 R2 and NIST SP 800-218 are guidelines, not regulations. NIST SP 800-171 Revision 3 is not currently applicable to this rule.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts, practices, and methodologies may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The National Institute of Standards and Technology (NIST) Information Technology Laboratory (ITL) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology (IT). ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security of other than national security-related information in federal information systems. The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information systems security and privacy and its collaborative activities with industry, government, and academic organizations. DEVELOPMENT OF INFORMATION SYSTEMS, COMPONENTS, AND

SERVICES

FDA is announcing the availability of a request for comment on its draft strategy, entitled "FDA Information Technology Strategy". The Office of Digital Transformation (ODT) was established in September 2021 and reports directly to the Office of the Commissioner. ODT provides the vision and leadership in information technology, data, and cybersecurity needed to advance FDA's mission and strategic priorities. ODT has published a series of strategy documents known as the FDA Modernization Framework. The framework includes the Technology Modernization Action Plan, Data Modernization Action Plan, Enterprise Modernization Action Plan, Cybersecurity Modernization Action Plan, and the Leadership Modernization Action Plan. The FDA Modernization Framework aims to develop an integrated technology, data, cybersecurity, business, and leadership approach to advancing FDA's public health mission in collaboration with industry. As part of FDA's fulfillment of requirements in section 3627 of the Consolidated Appropriations Act, 2023 (Pub. L. 117-328), and commitments described in section IV.A.2. of the "PDUFA Reauthorization Performance Goals and Program Enhancements Fiscal Years 2023-2027" (PDUFA VI commitment letter), FDA will work with industry while developing a comprehensive framework for guiding the Agency's work and allocating annual technology budgets and resources. The FDA IT Strategy, covering Fiscal Years 2024-2026, defines and shapes the future course of FDA's data and technology capabilities as FDA transitions to the next phase of its journey. The Agency took a collaborative approach to strategy development by gathering input from numerous internal and external stakeholders that resulted in the draft FDA IT Strategy. Stakeholder input is crucial for developing a comprehensive plan that best meets the needs and goals of industry and the Agency. Comments on the strategy will be considered for future iterations of the FDA IT Strategy. Once adopted, this strategy will serve as the basis for developing an internal operational plan with objectives, tactics, and performance measures. As part of this effort, FDA will hold an FDA Digital Transformation Symposium on December 4 to 7, 2023, to discuss this groundbreaking IT Strategy and encourage further collaboration, innovation, and transformation. On December 4 and 5, the Symposium will be shaped around the six new strategic goals, highlighting supporting objectives and initiatives. The FDA Digital Transformation Symposium will extend to December 6 and 7 to engage IT vendors in a Reverse Industry Day and other vendor-focused events. Registration information will be found on www.FDA.gov for this event. (printed page 64437) II. Requested Feedback Interested persons are invited to provide detailed comments to ODT (see ADDRESSES

(A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(14)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) Records maintained solely for statistical research or program evaluation purposes and which are not used to make decisions on the rights, benefits, or entitlement of an individual except for census records which may be disclosed under 13 U.S.C. 8 , may be exempt pursuant to 5 U.S.C. 552a(k)(4) . (C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (D) All portions of this system of records which fall within the scope of (printed page 14797) 5 U.S.C. 552a(k)(2) , (k)(4), and (k)(5) may be exempt from the provisions of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) , (k)(4), and (k)(5). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would place the subject of an investigation on notice that they are under investigation and provide them with significant information concerning the nature of the investigation, thus resulting in a serious impediment to law enforcement investigations. (B) From subsections (d) and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of

evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding.

The DoD does not use mercenaries. Article 47 of Additional Protocol I to Geneva Conventions provides an internationally accepted definition of mercenaries. The elements of that definition clearly exclude PSCs under contract to DoD. Private security contractors do not perform military functions, but rather, they carry out functions similar to those performed by security guards in the United States and elsewhere. We agree that the behavior of PSCs may affect the national security goals of the U.S. and for this reason we have published guidance on the selection, oversight, and management of private security contractors operating in contingency operations. Comment: DoD personnel do not want PSCs in a combat situation Response: The primary role of the armed forces is combat: to close with and destroy enemy armed forces through firepower, maneuver, and shock action. Defense of military personnel and activities against organized attack is a military responsibility. DoD allocates military personnel to these high priority combat and other critical combat support missions. Private Security Companies contracted by the U.S. government protect personnel, facilities and activities against criminal activity, including individual acts of terrorism. They are specifically prohibited from engaging in combat (offensive) operations and certain security functions. DoD PSCs have performed well and are very important to our mission accomplishment in the CENTCOM area of responsibility. Comment: PSCs should receive Veteran's Affairs benefits for injuries sustained while protecting the country Response: PSCs and other contractors employed by the U.S. government who perform work outside of the United States are covered by the Longshore and Harbor Workers' Compensation Act (LHWCA). The LHWCA provides disability compensation and medical benefits to employees and death benefits to eligible survivors of employees of U.S. government contractors who perform work overseas. The Defense Base Act is an extension of the LHWCA. The Defense Base Act covers the following employment activities: (1) Work for private employers on U.S. military bases or on any lands used by the U.S. for military purposes outside of the United States, including those in U.S. Territories and possessions; (2) Work on public work contracts with any U.S. government agency, including construction and service contracts in connection with national defense or with war activities outside the United States; (3) Work on contracts approved and funded by the U.S. under the Foreign Assistance Act, which among other things provides for cash sale of military equipment, materials, and services to its allies, if the contract is performed outside of the United States; or (4) Work for American employers providing welfare or similar services outside the United States for the benefit of the Armed Services, e.g.

From the NIST SP 800-172 Rev 3 Final Public Draft: Concealment and misdirection techniques may provide additional time to perform NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 core mission and business functions. The implementation of concealment and 1808

According to Cryptographic Key Management Workshop Summary -- June 8-9, 2009, 2.1.5 Internet Key Management Security: Russ Housley, IETF Chair, Vigil Sec.: increases complexity, but also allows transition more easily when an algorithm gets old or broken. - There have been a lot of transitions from one algorithm to another in encryption and secure hashing. The Internet community sees a need to respond to these changes in algorithms, especially when a security flaw is found, but seldom in other circumstances. A transition takes 5 to 15 years, and the cost of implementation, testing and deployment are high because it causes a loss of interoperability in some circumstances.

The requester is responsible to provide a description of the desired record that enables the Government to locate the record with a reasonable amount of effort. Generally, a reasonable description contains sufficient information to permit the conduct of an organized, non-random search for the record based on the DoD Component's filing arrangements and existing retrieval systems. The DoD Component's decision on the reasonableness of the description must be based on a knowledge of its files, and not on the potential volume of records that may be located and the concurrent review effort to determine releasability. The fact that a FOIA request appears broad or burdensome does not, in itself, entitle the DoD Component to deny the request on the grounds that it does not reasonably describe the record sought. (h) Consultations and referrals. The DoD FOIA referral procedures are based on the concept that the originator of information contained within a record shall make a release determination on that information. (1) If the DoD Component receives a request

for records originated by another DoD Component, it should contact that Component to determine if it also received the request, and if not, obtain concurrence to transfer the request or to advise the requester to send the request to the correct Component. If the request is to be transferred, the requester shall be advised of the action taken, unless exempt information would be revealed by the fact of the referral. Any DoD Component receiving a request that has been misaddressed shall transfer the request to the proper address and advise the requester. DoD Components transferring requests shall include point of contact name, telephone number, and e-mail address in the cover memorandum. (2) The DoD Component holding a record originated by another DoD Component or agency outside the Department of Defense shall refer a FOIA request for that record, as well as the record, to the originating agency for response directly to the requester. If the DoD Component holding the record has an equity in the document, it shall provide an opinion on the releasability of the record with the referral. If appropriate, the name of the IDA responsible for the decision to withhold all or parts of the record should be provided. Whenever a record is referred to another DoD Component or to an agency outside of the Department of Defense for a release determination and direct response, the requester shall be informed of the referral, unless it has been determined that notification would reveal exempt information. Referred records shall only be identified to the extent consistent with security requirements. DoD Components referring requests shall include point of contact name, telephone number, and e-mail address in the cover memorandum. (3) At times, a DoD Component may locate a responsive record that it (printed page 71851)

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Health and Human Services Food and Drug Administration 21 CFR Parts 1 and 11 [Docket No. 2002N-0277] RIN 0910-AC39 AGENCY: Food and Drug Administration, HHS. ACTION: Final rule. SUMMARY: The Food and Drug Administration (FDA) is issuing a final regulation that requires the establishment and maintenance of records by persons who manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States. Such records are to allow for the identification of the immediate previous sources and immediate subsequent recipients of food. The final rule implements the Public Health Security and Bioterrorism Preparedness and Response Act of 2002 (the Bioterrorism Act), and is necessary to help address credible threats of serious adverse health consequences or death to humans or animals. The requirement to establish and maintain records is one of several tools that will help improve FDA's ability to respond to, and further contain, threats of serious adverse health consequences or death to humans or animals from accidental or deliberate contamination of food. In the event of an outbreak of foodborne illness, such information will help FDA and other authorities determine the source and cause of the event. In addition, the information will improve FDA's ability to quickly notify the consumers and/or facilities that might be affected by the outbreak. DATES: Effective Date : This final rule is effective February 7, 2005. Compliance Dates : The compliance date is December 9, 2005; except that for small businesses employing fewer than 500, but more than 10 full-time equivalent employees, the compliance date is June 9, 2005; and except that for very small businesses that employ 10 or fewer full-time equivalent employees, the compliance date is December 11, 2006. FOR FURTHER INFORMATION CONTACT: Nega Beru, Center for Food Safety and Applied Nutrition (HFS-305), Food and Drug Administration, 5100 Paint Branch Pkwy., College Park, MD 20740, 301-436-1400. SUPPLEMENTARY INFORMATION: Table of Contents I. Background and Legal Authority II. Highlights of the Final Rule and Summary of the Significant Changes Made to the Proposed Rule A. Highlights of This Final Rule B. Significant Changes FDA Made to the Proposed Rule III. Comments on the Proposed Rule A. General Comments B. Foreign Trade Issues C. Comments on Who is Subject to This Subpart? (Proposed § 1.326) D. Comments on Who is Excluded From All or Part of the Regulations in this Subpart? (Proposed § 1.327)

In the past year, NIST continued to support the EAC in finalizing changes to the Voluntary Voting System Guidelines (VVSG) 1.1. The security guidelines were updated in FY 2012 to improve the auditability of voting systems, to provide greater software integrity protections, to expand and improve access-control requirements, and to help ensure - Updates on the OCR audit and enforcement programs; - Use of the NIST Cybersecurity Framework in the healthcare sector; - Safeguarding data using cryptographic technologies and strong identity and access management; - Strategies for engaging the executive leadership to privacy and security risks; and - Case studies on safeguarding

patient information, and lessons learned for health data breaches. This year's annual two-day offsite meeting featured updates on the computer security activities of the Government Accountability Office (GAO), General Services Administration (GSA), Bureau of the Fiscal Service, Department of State, National Security Council, Department of Homeland Security (DHS), and NIST. Technical sessions included briefings on updates from NIST Computer Security Division (CSD), FedRAMP Overview and Security Processes, Supply Chain Risk Management, Ongoing Authorization, Fiscal Service's Risk-Based ISCM Strategy, Derived PIV Credentials, Cybersecurity Training, Incident Response, White House Initiatives, FY 2015 FISMA Metrics and recent updates to the FISMA publications.

(B) The CSA will provide transmission instructions to the contractor. The material will be (printed page 83357) addressed to a U.S. organization at NATO, which will then place the material into NATO security channels. The material will be accompanied by a letter to the U.S. organization that provides transfer instructions and assurances that the material has been authorized for release to NATO. The inner wrapper will be addressed to the intended NATO recipient. (C) Material to be sent to NATO via mail will be routed through the U.S. Postal Service and U.S. military postal channels to the U.S. organization that will make the transfer. (ii) A record will be maintained that identifies the originator and source of classified information that are used in the preparation of documents for release to NATO. The record will be provided with any request for release authorization. (22) Visits. NATO visits will be handled in accordance with the requirements in paragraph (e) of this section. A NATO Certificate of Security Clearance will be included with the visit request. (i) NPLO and NATO industrial advisory group (NIAG) recurring visits. NATO has established special procedures for recurring visits involving contractors, government departments and agencies, and NATO commands and agencies that are participating in a NPLO or NIAG contract or program. The NATO management office or agency responsible for the NPLO program will prepare a list of the government and contractor facilities participating in the program. For NIAG programs, the list will be prepared by the responsible NATO staff element. The list will be forwarded to the appropriate clearance agency of the participating nations, which will forward it to the participating contractor. (ii) Visitor record. The contractor will maintain a record of NATO visits including those by U.S. personnel assigned to NATO. The records will be maintained for three years. (h) Security and export control violations involving foreign nationals. Contractors will report any violation of administrative security procedures or export control regulations that would subject classified information to possible compromise by foreign visitors or foreign national employees to the applicable CSA. (i) Transfers of defense articles to the UK or AUS without a license or other written authorization. (1) Treaties with AUS and UK. Exemptions in ITAR parts 126.16 and 126.17 implement the Defense Trade Cooperation Treaty between the Government of the United States of America and the Government of the UK of Great Britain and Northern Ireland and the Defense Trade Cooperation Treaty between the Government of the United States of America and the Government of AUS, also known as the U.S.-UK Treaty and U.S.-AUS Treaty, respectively, referred to collectively in this rule as the Treaties.

is required to perform regular third-party assessments, including penetration testing and vulnerability assessments. Palo Alto Networks' products are not built or packaged for any particular customer. Rather, the CM prepares prepackaged inventory to satisfy sales forecasts and prevent would-be attackers from targeting specific customers during the production phase.

(B) From subsection (d) because these provisions concern individual access to and amendment of open or closed investigation records contained in this system, including law enforcement and investigatory records. Compliance with these provisions would provide the subject of an investigation of the fact and nature of the investigation, and/or the investigative interest of the Pentagon Force Protection Agency; compromise sensitive information related to national security; interfere with the overall law enforcement process by leading to the destruction of evidence, improper influencing of witnesses, fabrication of testimony, and/or flight of the subject; could identify a confidential informant or disclose information which would constitute an unwarranted invasion of another's personal privacy; reveal a sensitive investigative or constitute a potential danger to the health or safety of law enforcement personnel, confidential informants, and witnesses. Amendment of investigative records would interfere with open or closed administrative or civil law enforcement investigations and analysis activities and impose an excessive administrative burden by requiring investigations, analyses, and reports to be continuously reinvestigated and revised. (C) From subsections (e)(1) through (e)(3) because it is not always possible to determine what

information is relevant and necessary in open or closed investigations. (D) From subsections (e)(4)(G) through (I) (Agency Requirements) because portions of this system are exempt from the access and amendment provisions of subsection (d). (E) From subsection (e)(5) because the requirement that investigative records be maintained with attention to accuracy, relevance, timeliness, and completeness would unfairly hamper the criminal, administrative, or civil investigative process. It is the nature of Internal Affairs investigations to uncover the commission of illegal acts and administrative violations. It is frequently impossible to determine initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. (F) From subsection (f) because requiring the Agency to grant access to records and establishing agency rules for amendment of records would compromise the existence of any criminal, civil, or administrative enforcement activity. To require the confirmation or denial of the existence of a record pertaining to a requesting individual may in itself provide an answer to that individual relating to the existence of an on-going investigation. The investigation of possible unlawful activities would be jeopardized by agency rules requiring verification of the record, disclosure of the record to the subject, and record amendment procedures.

This publication differs significantly from previous versions of NIST IR 7298. Previous versions contained a subset of basic terms that were most frequently used in NIST publications. This method was valuable, but greater demand and frequent updates to NIST's publication suite has necessitated the adoption of a more flexible solution. ## 3 Feedback & Updates

mission, functions, image, and reputation), organizational assets, individuals, other organizations, and the Nation resulting from the operation and use of federal information systems. SP 800-39 provides a structured, yet flexible approach for managing risk that is intentionally broad-based, with the specific details of assessing, responding to, and monitoring risk on an ongoing basis provided by other supporting NIST security standards and guidelines. The guidance provided in this publication is not intended to replace or subsume other risk-related activities, programs, processes, or approaches that organizations have implemented or intend to implement addressing areas of risk management covered by other legislation, directives, policies, programmatic initiatives, or mission/business requirements. Rather, the risk management guidance described herein is complementary to and should be used as part of a more comprehensive Enterprise Risk Management (ERM) program. This document is incorporated by reference as a source for definitions. (e) NIST SP 800-53, revision 5, titled "Security and Privacy Controls for Information Systems and Organizations" provides a catalog of security and privacy controls for information systems and organizations to protect organizational operations and assets, individuals, other organizations, and the Nation from a diverse set of threats and risks, including hostile attacks, human errors, natural disasters, structural failures, foreign intelligence entities, and privacy risks. The controls are flexible and customizable and implemented as part of an organization-wide process to manage risk. The controls address diverse requirements derived from mission and business needs, laws, executive orders, directives, regulations, policies, standards, and guidelines. Finally, the consolidated control catalog addresses security and privacy from a functionality perspective (i.e., the strength of functions and mechanisms provided by the controls) and from an assurance perspective (i.e., the measure (printed page 89062) of confidence in the security or privacy capability provided by the controls). Addressing functionality and assurance helps to ensure that information technology products and the systems that rely on those products are sufficiently trustworthy. This document is incorporated by reference as a source for definitions.

| Security Incident Procedures | 164.308(a)(6) | Response and Reporting (R) | | Contingency Plan | 164.308(a)(7) | Data Backup Plan (R) | | Contingency Plan | 164.308(a)(7) | Disaster Recovery Plan (R) | | Contingency Plan | 164.308(a)(7) | Emergency Mode Operation Plan (R) | | Contingency Plan | 164.308(a)(7) | Testing and Revision Procedure (A) | | Contingency Plan | 164.308(a)(7) | Applications and Data Criticality Analysis (A) | | Evaluation | 164.308(a)(8) | (R) | | Business Associate Contracts and Other Arrangements | 164.308(b)(1) | Written Contract or Other Arrangement (R) | | Physical Safeguards | Physical Safeguards | Physical Safeguards | | Facility Access Controls | 164.310(a)(1) | Contingency Operations (A) | | Facility Access Controls | 164.310(a)(1) | Facility Security Plan (A) | | Facility Access Controls | 164.310(a)(1) | Access Control and Validation Procedures (A) | | Facility Access Controls | 164.310(a)(1) | Maintenance Records (A) | | Workstation Use | 164.310(b) | (R) | | Workstation Security | 164.310(c) | (R) | | Device and Media Controls | 164.310(d)(1) | Disposal (R) | | Device and Media Controls | 164.310(d)(1) | Media Re-use

(k)(7) Exemption for promotion evaluation materials used by the Armed Forces. Yes No (l)(1) Records stored in GSA records centers. Yes No (l)(2) Records archived before September 27, 1975. Yes No (l)(3) Records archived on or after September 27, 1975. (printed page 18786) Yes No (m) Applicability to Government contractors. Yes No (n) Mailing lists. Yes 1 No (o) Reports on new systems. Yes 1 No (p) Annual report. 1 See paragraph (d) of §-310.26. Appendix E to Part 310-Sample of New or Altered System of Records Notice in Federal Register Format (See paragraph (f) of §-310.30) New system of records notice DEPARTMENT OF DEFENSE Office of the Secretary Privacy Act of 1974; System of Records AGENCY: Office of the Secretary, DoD. ACTION: Notice to add a system of records. SUMMARY: The Office of the Secretary of Defense proposes to add a system of records to its inventory of record systems subject to the Privacy Act of 1974 (5 U.S.C. 552a), as amended. DATES: The changes will be effective on (insert date thirty days after publication in the Federal Register) unless comments are received that would result in a contrary determination. ADDRESSES: Send comments to OSD Privacy Act Coordinator, Records Management Section, Washington Headquarters Services, 1155 Defense Pentagon, Washington, DC 20301-1155. FOR FURTHER INFORMATION CONTACT: Ms. Mary Smith at (703) 000-0000. SUPPLEMENTARY INFORMATION: The Office of the Secretary of Defense notices for systems of records subject to the Privacy Act of 1974 (5 U.S.C. 552a), as amended, have been published in the Federal Register and are available from the address above. The proposed systems reports, as required by 5 U.S.C. 552a(r) of the Privacy Act of 1974, as amended, were submitted on January 20, 2006, to the House Committee on Government Reform, the Senate Committee on Homeland Security and Governmental Affairs, and the Office of Management and Budget (OMB) pursuant to paragraph 4c of Appendix I to OMB Circular No. A-130, Federal Agency Responsibilities for Maintaining Records About Individuals, dated February 8, 1996 (February 20, 1996, 61 FR 6427). Dated: February 1, 2006. John Miller, OSD Federal Register Liaison Officer, Department of Defense. NSLRB 01 System name: The National Security Labor Relations Board (NSLRB). System location: National Security Labor Relations Board (NSLRB), 1401 Wilson Boulevard, Arlington, VA 22209-2325. Categories of individuals covered by the system: Current and former civilian Federal Government employees who have filed unfair labor practice charges, negotiability disputes, exceptions to arbitration awards, and impasses with the National Security Labor Relations Board (NSLRB) pursuant to the National Security Personnel System (NSPS). Categories of records in the system:

Below is a summary of the findings and observations made during the agency security needs study, expressed in terms of issues that emerge from the study. As may be expected, remarks made in the interviews and additional comments offered by survey respondents do not fall into neat, distinct categories. Overlaps and interrelationships exist.

ESPs that are not CSPs may request voluntary CMMC assessments of their environment and use that as a business discriminator. The marketplace for ESP services will adjust to find the efficient manner for ESPs to support OSA assessments that may include their services. With respect to requirement AC.L3-3.1.2e, when an OSA adds an ESP's services to its network, the ESP is considered to be provisioned by the OSA. It is subject to the requirements for the use of an ESP. A common carrier's information system is not within the contractor's CMMC Assessment Scope if CUI is properly encrypted during transport across the common carrier's information system. In a cloud model, the end-to-end encryption would apply when transmitting between OSA CUI assets and a cloud service. Once within the security boundary of the CSP, the common carrier's system no longer contributes to the handling of the CUI and the CSP's security practices apply. If an OSA chooses to use a CSP to process, store, or transmit CUI, FedRAMP Moderate or equivalency requirements apply. The rule has been updated to include the use of a Customer Responsibility Matrix by all ESPs, not just CSPs. Obtaining a copy of a CSP's SSP is not required for a CSP that is FedRAMP Authorized. Documentation on the services provided by the CSP and a CRM will be required. e. Capacity for Assessment of ESPs Comment: Some comments questioned whether the CMMC ecosystem would be adequate to provide the number of CMMC assessments necessary for ESPs. In response, some comments recommend ESPs be given priority for completing assessments. Others recommend different phasing or forms of assessment and certification during ramp up. Response: DoD declines to make suggested changes to the ramp up and phasing of assessments for ESPs. DoD considered many alternatives before deciding upon the current CMMC assessment structure. By design, the CMMC program depends on the supply and demand dynamics of the free market, enabling it to naturally scale and adapt to capacity requirements. DoD declines to set priorities for the assessment marketplace. The DoD has utilized a phased implementation approach to

reduce implementation risk. DoD expects that the public has utilized the lead-time prior to the publication of this rule to prepare for CMMC implementation and buy-down risk. CMMC Program requirements make no changes to existing policies for information security requirements implemented by the DoD. It is beyond the scope of this rule for DoD to determine the order in which organizations are assessed. f. Remote Access by ESPs Comment: Two comments ask for clarification on requirements for remote access by an ESP to an OSA, whether with OSA provided equipment or a VPN. Response:

3.3.2 Collateral Damage Potential (CDP) The Collateral Damage Potential metric measures the potential for loss of life or physical assets through damage or theft of property or equipment.

Offerors and contractors are required to notify the contracting officer representative or other designated agency official concerning any unmarked or mismarked CUI if discovered. These potential costs are not quantified since such occurrences are expected to be rare. In addition, to the maximum extent practicable, the offeror or contractor shall identify and mark its proprietary business and attributional information. These costs are also not quantified since an offeror or contractor usually marks its proprietary information as a best business practice to protect its own interests and information. Finally, offerors are required to notify the contracting officer of a potential CUI incident within 8 hours of discovery. Such occurrences are expected to be rare and are assumed to be accounted for under the public cost estimate for CUI incident reporting in section IV.C.2.b. of this preamble. 2. Non-Defense Contractors and Subcontractors a. Comply With NIST SP 800-171 Revision 2 A contractor may need to depend on the expertise of information security specialists to develop and document processes and procedures associated with each security requirement, perform the periodic scans, tests, and assessments necessary for some of the security requirements, and analyze the results. The amount of time necessary to perform the various tasks will vary by contractor depending on the number of employees and the complexity of its information systems. Some contractors may already have personnel performing some of the functions as a matter of good business practice to protect their (printed page 4284) networks, while others may be starting with no in-house expertise. The total estimated labor cost for a small business in the initial year is approximately \$148,200 (average of 1,560 hours * \$95), with a recurring annual labor cost of approximately \$98,800 (1,040 hours * \$95). The total estimated labor cost for a business other than a small business in the initial year is approximately \$543,400 (average of 5,720 hours * \$95), with a recurring annual labor cost of approximately \$494,000 (5,200 hours * \$95). Note, this does not include the time expected to maintain the system security plan (see section IV.C.2.d. of this preamble). Businesses may also need to install software and/or hardware to implement NIST SP 800-171 Revision 2. Similar to the labor costs, the cost of the specific software or hardware varies based on the solution selected by the business, a decision that will take into consideration the number of users, the types of devices used, and the complexity of the network, among other things. The Government estimates that a small business, on average, may spend \$27,500 on hardware and software during initial implementation and \$5,000 annually thereafter to maintain compliance. On average, a business other than a small business may spend \$140,000 on hardware and software in the initial year and \$80,000 annually thereafter.

(A) AC.L2-3.1.20 External Connections (CUI Data). (B) AC.L2-3.1.22 Control Public Information (CUI Data). (C) PE.L2-3.10.3 Escort Visitors (CUI Data). (D) PE.L2-3.10.4 Physical Access Logs (CUI Data). (E) PE.L2-3.10.5 Manage Physical Access (CUI Data). (3) CMMC Level 3 Certification Assessment. An OSC is only permitted to have a POA&M for CMMC Level 3 if all the following conditions are met: (printed page 89136) (i) The assessment score divided by the total number of CMMC Level 3 security requirements is greater than or equal to 0.8; and (ii) The POA&M does not include any of following security requirements: (A) IR.L3-3.6.1e Security Operations Center. (B) IR.L3-3.6.2e Cyber Incident Response Team. (C) RA.L3-3.11.1e Threat-Informed Risk Assessment. (D) RA.L3-3.11.6e Supply Chain Risk Response. (E) RA.L3-3.11.7e Supply Chain Risk Plan. (F) RA.L3-3.11.4e Security Solution Rationale. (G) SI.L3-3.14.3e Specialized Asset Security. (b) POA&M Closeout assessment. The closing of a POA&M must be confirmed by a POA&M Closeout assessment within 180-days of the initial assessment. A POA&M Closeout assessment is a CMMC assessment that assesses only the NOT MET requirements that were identified with POA&M in the initial assessment. (1) CMMC Level 2 Self-Assessment. For a CMMC Level 2 Self-Assessment, the POA&M Closeout assessment shall be performed by the OSA in the same manner as the initial self-assessment. (2) CMMC Level 2 Certification Assessment. For CMMC Level 2 Certification Assessment, the POA&M Closeout assessment must be performed by an authorized or accredited C3PAO. (3) CMMC Level 3

Certification Assessment. For CMMC Level 3 Certification Assessment, DCMA DIBCAC will perform the POA&M Closeout Assessment of the CMMC Level 3 security requirements. § 170.22 Affirmation. (a) General. The OSA must affirm continuing compliance with the appropriate level CMMC Self-Assessment or CMMC Certification Assessment. The affirmation shall be submitted in accordance with the following requirements: (1) Affirming official. All CMMC affirmations shall be submitted by the OSA senior official who is responsible for ensuring OSA compliance with CMMC Program requirements. (2) Affirmation content. Each CMMC affirmation shall include the following information: (i) Name, title, and contact information for the affirming official; and (ii) Affirmation statement attesting that the OSA has implemented and will maintain implementation of all applicable CMMC security requirements for all information systems within the relevant CMMC Assessment Scope at the applicable CMMC Level. (3) Affirmation submission. The affirming official shall submit a CMMC affirmation in the following instances: (i) Upon completion of the assessment (conditional or final); (ii) Annually thereafter; and (iii) Following a POA&M closeout assessment, as applicable. (b) Submission procedures.

Nothing in this section shall alter the requirements of a covered entity or business associate to comply with applicable provisions of this part other than §§ 164.308(b) and 164.314(a). § 164.320 Severability. If any provision of this subpart is held to be invalid or unenforceable by its terms, or as applied to any person or circumstance, or stayed pending further agency action, it shall be construed so as to give it maximum effect permitted by law, unless such holding shall be one of utter invalidity or unenforceability, in which event such provision shall be severable from this subpart and shall not affect the remainder thereof or the application of such provision to other persons not similarly situated or to other dissimilar circumstances. (printed page 1021)

Appendix A to Subpart C of Part 164-Security Standards: Matrix Standards Sections Implementation specifications Administrative Safeguards Technology asset inventory 164.308(a)(1) Inventory. Network map. Maintenance. Risk analysis 164.308(a)(2) Assessment Maintenance. Evaluation 164.308(a)(3) Performance Response. Patch Management 164.308(a)(4) Policies and procedures. Maintenance. Application. Exceptions. Alternative measures. Compensating controls. Risk management 164.308(a)(5) Planning. Maintenance. Priorities. Implementation. Sanction policy 164.308(a)(6) Policies and procedures. Modifications. Application. Information system activity review 164.308(a)(7) Policies and procedures. Scope. Record review. Record retention. Response. Maintenance. Assigned security responsibility 164.308(a)(8) Workforce security 164.308(a)(9) Authorization and/or supervision. Workforce clearance procedure. Modification and termination procedures. Notification. Maintenance. Information access management 164.308(a)(10) Isolating health care clearinghouse functions. Access authorization. Authentication management. Access determination and modification. Network segmentation. Maintenance. Security awareness training 164.308(a)(11) Training. Timing. Ongoing education. Documentation. Security incident procedures 163.308(a)(12) Planning and testing. Response. Contingency plan 163.308(a)(13) Criticality analysis. Data backups. Information systems backups. Disaster recovery plan. Emergency mode operation plan. Testing and revision procedures. Compliance audit 164.308(a)(14) Business associate contracts and other arrangements 164.308(b)(1) Written contract or other arrangement. Written verification. Delegation to business associate 164.308(b)(3) Physical Safeguards Facility access controls 164.310(a) Contingency operations. Facility security plan. Access management and validation procedures. Physical maintenance records. Maintenance. Workstation use 164.310(b) Policies and procedures. Maintenance. Workstation security 164.310(c) Technology asset controls 164.310(d) Disposal. Media sanitization. Maintenance. (printed page 1022) Technical Safeguards Access control 164.312(a) Unique identification. Administrative and increased access privileges. Emergency access procedure. Automatic logoff. Log-in attempts. Network segmentation.

· Conducted by OSA every 3 years · Results entered into SPRS (or its successor capability). · CMMC Status will be valid for three years from the CMMC Status Date as defined in § 170.4. · Permitted as defined in § 170.21(a)(2) and must be closed out within 180 days · Final CMMC Status will be valid for three years from the Conditional CMMC Status Date. · After each assessment and annually thereafter. · Assessment will lapse upon failure to annually affirm. · Entered into SPRS (or its successor capability). Level 2 (C3PAO) · 110 NIST SP 800-171 R2 required by DFARS clause 252.204-7012 · Conducted by C3PAO every 3 years · Results entered into CMMC Enterprise Mission Assurance Support Service (eMASS) (or its successor capability). · CMMC Status will be valid for three years from the CMMC Status Date as defined in § 170.4. · Permitted as defined in § 170.21(a)(2) and must be closed out within 180 days · Final CMMC Status will be valid for three

years from the Conditional CMMC Status Date. · After each assessment and annually thereafter. · Assessment will lapse upon failure to annually affirm. · Entered into SPRS (or its successor capability). Level 3 (DIBCAC) · 110 NIST SP 800-171 R2 required by DFARS clause 252.204-7012 · 24 selected from NIST SP 800-172 Feb2021, as detailed in table 1 to §170.14(c)(4). · Pre-requisite CMMC Status of Level 2 (C3PAO) for the same CMMC Assessment Scope, for each Level 3 certification assessment · Conducted by Defense Contract Management Agency (DCMA) Defense Industrial Base Cybersecurity Assessment Center (DIBCAC) every 3 years. · Results entered into CMMC eMASS (or its successor capability). · CMMC Status will be valid for three years from the CMMC Status Date as defined in §170.4. · Permitted as defined in §170.21(a)(3) and must be closed out within 180 days · Final CMMC Status will be valid for three years from the Conditional CMMC Status Date. · After each assessment and annually thereafter. · Assessment will lapse upon failure to annually affirm. · Level 2 (C3PAO) affirmation must also continue to be completed annually. · Entered into SPRS (or its successor capability). Program Walkthrough-Contractor Perspective This section will provide a simplified walkthrough of the CMMC Program from the perspective of an Organization Seeking Assessment (OSA) seeking to comply with program requirements. CMMC Level Selection An OSA will select the CMMC level it desires to attain. Once the CMMC Program is implemented, a DoD solicitation will specify the minimum CMMC Status required to be eligible for award. One of four CMMC Statuses will be specified: Level 1 (Self) is a self-assessment to secure FCI processed, stored, or transmitted in the course of fulfilling the contract. The OSA must comply with the 15 security requirements set by FAR clause 52.204-21. All 15 requirements must be met in full-no exceptions are allowed.

the CSA can determine that TOP SECRET material stored in an electronic format on an authorized classified information system does not need to be individually numbered in series provided the contractor has in place controls in place to address accountability, need to know and retention). As stated in this paragraph: · . . . Contractors will establish controls for TOP SECRET information and material to validate procedures are in place to address accountability, need to know and retention, e.g., demonstrating that TOP SECRET material stored in an electronic format on an authorized classified information system does not need to be individually numbered in series. These controls are in addition to the information management system and must be applied, unless otherwise directed by the applicable CSA, regardless of the media of the TOP SECRET information, to include information processed and stored on authorized information systems. Unless otherwise directed by the applicable CSA, the contractor will establish the following additional controls . . . · §117.15(d)(4) Installation: Clarifies that an Intrusion Detection System (IDS) shall be installed by a Nationally Recognized Testing Laboratory (NRTL)-approved entity to make it clear that any NRTL-approved entity may do such (printed page 83305) installations. ·The IDS will be installed by a NRTL-approved entity or by an entity approved in writing by the CSA . . . · §117.7(b)(2) Senior Management Official: Clarifies responsibilities of the Senior Management Official of each cleared entity to better reflect the critical role and accountability of this position for entity compliance with the NISPOM. This change further emphasizes the essential role of the Senior Management Official with the entity's security staff to ensure NISPOM compliance. · §117.13(d)(5) Clarifies to the contractor that upon completion of a classified contract, the contractor must return all government provided or deliverable information to the custody of the government. Such clarification ensures the contractor is not retaining official government records without specific authorization from the government customer. ·(i) If the GCA does not advise to the contrary, the contractor may retain copies of the government material for a period of 2 years following the completion of the contract. The contract security classification specification, or equivalent, will continue in effect for this 2-year period. (ii) If the GCA determines the contractor has a continuing need for the copies of the government material beyond the 2-year period, the GCA will issue a final contract security classification specification, or equivalent, for the classified contract and will include disposition instructions for the copies. · Costs The DoD invites comment from the members of the public on the costs estimated to implement this rule. A. Baseline

CIS Safeguard 5.3 · Disable Dormant Accounts Delete or disable any dormant accounts after a period of 45 days of inactivity, where supported Implementation Groups: 1,2,3 Asset Type: users Security Function: respond Parent Control: Account Management

the OSA provides all processes, technology, and facilities, does not need CMMC assessment. When ESPs are assessed as part of an OSA's assessment, the assessment type is dictated by the OSA's DoD contract CMMC requirement. The DoD declines to make any other suggested changes to the assessment of

ESPs. b. Definitions Comment: Multiple comments state that the definition of CSP in the rule is overly broad and overlaps with the definition of ESP. One comment questioned whether a C3PAO is also a Security Protection Asset and by extension an ESP. Two comments requested change to the definition of Out-of-Scope Assets to stipulate that SPD is Out-of-Scope. Response: Several comments requested clarification on when an ESP would be considered a CSP. CSPs, MSPs, and MSSPs are always considered ESPs. The DoD has updated the rule to narrow the definition of Cloud Service Provider based on the definition for cloud computing from NIST SP 800-145 Sept2011. An ESP would be considered a CSP when it provides its own cloud services based on a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing that can be rapidly provisioned and released with minimal management effort or service provider interaction on the part of the OSA. An ESP (not a CSP) that provides technical support services to its clients would be considered an MSP. It does not host its own cloud platform offering. An ESP may utilize cloud offerings to deliver services to clients without being a CSP. An ESP that manages a third-party cloud service on behalf of an OSA would not be considered a CSP. C3PAOs need not receive security protection data as part of an assessment; they view the security protection data while on premises at the OSC for the assessment. A C3PAO is not an ESP or security protection asset and is therefore not within the OSA assessment boundary. DoD declines to delete the phrase "except for assets that provide security protection for a CUI asset" from the definition of Out-of-Scope Assets. Assets that provide security protection for CUI are not Out-of-Scope Assets. A CMMC definition for Security Protection Data has been added to the rule. c. OSA Relationship to ESP Comment: Several comments request clarification related to use of an ESP that is internal to the OSA. One comment requested that DoD require CSPs grant the US Government, as part of the contract between the OSA and the CSP, access to any CUI that is subject to CMMC requirements in the event of contractual failures, criminal actions or other legal situations that warrant seizure of CUI data. Some comments also asked whether the DoD has standing or authority to require C3PAO assessment or conduct CMMC level 3 assessments of ESPs, given that the ESP's direct contractual relationship is not with the Government but with the OSA. Two comments suggest that ESPs will be covered by the subcontractor flow down requirements from an OSA. Response:

33] assessment costs, and affirmation costs for each CMMC Level. For CMMC Levels 1 and 2, the cost estimates are based only upon the assessment, certification, and affirmation activities that a defense contractor, subcontractor, or ecosystem member must take to allow DoD to verify implementation of the relevant underlying security requirements, i.e., for CMMC Level 1, the security requirements set forth in FAR clause 52.204-21, and for CMMC Level 2, the security requirements set forth in NIST SP 800-171 Rev 2. DoD did not consider the cost of implementing the security requirements themselves because implementation is already required by FAR clause 52.204-21, effective June 15, 2016, and by DFARS clause 252.204-7012, requiring implementation by Dec. 31, 2017, respectively; therefore, the costs of implementing the security requirements for CMMC Levels 1 and 2 should already have been incurred and are not attributed to this rule. As such, the nonrecurring engineering and recurring engineering costs to implement the security requirements defined for CMMC Level 1 and Level 2 are not included in this economic analysis. However, cost estimates to implement CMMC Level 3, are included, as that CMMC level will require defense contractors and subcontractors, as applicable, to implement a DoD-defined subset of the security requirements set forth in NIST SP 800-172, a new addition to current security protection requirements. In estimating the public cost for a defense contractor small entity to comply with CMMC Program requirements for each CMMC level, DoD considered non-recurring engineering costs, recurring engineering costs, assessment costs, and affirmation costs for each CMMC Level. These costs include labor and consulting. Estimates include size and complexity assumptions to account for typical organizational differences between small entities and other than small entities with respect to the handling of Information Technology (IT) and cybersecurity: small entities are likely to have a less complex, less expansive operating environment and IT/Cybersecurity infrastructure compared to larger defense contractors small entities are likely to outsource IT and cybersecurity to an External Service Provider (ESP) entities (small and other than small) pursuing CMMC Level 2 Self-Assessment are likely to seek consulting or implementation assistance from an ESP to either help them prepare for the assessment technically or participate in the assessment with the C3PAOs. Estimates do not include the cost to implement (Non-recurring Engineering Costs (NRE)) or maintenance costs (Recurring Engineering (RE)) the (printed page 89088) security requirements prescribed in current regulations.

. Not allowing for a transition period could have an opportunity cost whereby regulated entities

spend their limited time revising business associate agreements instead of enhancing their cybersecurity posture. The Department believes that this could result in duplicative costs because some regulated entities may identify the need for additional changes to business associate agreements after they have fully evaluated their changed cybersecurity needs. The Department estimates that small regulated entities may be more likely to experience that outcome without a transition period, and thus the alternative of no transition period would cause a potential one-time increase in costs of \$278,332,891 $[(1,822,600 \text{ regulated entities} \times .9) \times 1 \text{ hour} \times \$169.68 \text{ lawyer hourly wage}]$. Relatedly, the Department considered proposing similar transition provisions for group health plans and plan sponsors that would provide these entities with additional time to update plan documents to align with new proposed requirements in this NPRM, if adopted. However, the Department believes that affected plans and plan sponsors would be able to complete any necessary updates by the proposed compliance date. The Department believes that updating plan documents is not as complex a task as evaluating potential new contractual needs to meet business associate obligations. Additionally, plan sponsors do not have Security Rule obligations independent of plan documents, and thus would not be obligated to implement the requirements proposed in this NPRM absent updates to the plan documents. The result of a transition period for updating plan documents would be merely to delay compliance with the changed Security Rule requirements, and therefore, delay improvements to their cybersecurity posture, not to reduce costs. Accordingly, we are not proposing such transition provisions in this NPRM.

C. Regulatory Flexibility Act-Small Entity Analysis The Department has examined the economic implications of this proposed rule as required by the RFA. If a rule has a significant economic impact on a substantial number of small entities, the RFA requires agencies to analyze regulatory options that would reduce the economic effect of the rule on small entities. As discussed in greater detail below, this analysis concludes, and the Secretary proposes to certify, that the proposed rule, if finalized, would not (printed page 1007) result in a significant economic effect on a substantial number of small entities.

(Comment 112) Some comments state that if foods are distributed to the store via direct store delivery (DSD) (i.e., baked goods, breads, soda, snack foods, beer/wine, ice, and milk) the vendor provides the food directly to the store and sometimes stocks the shelves. DSD has no system to track the information the FDA will require. Several comments note that protecting public health does not necessitate the maintenance of records in every step of the distribution process. The comments state that the current recall system is the most efficient and practical way to identify and remove product from distribution. These comments state that consumers typically return all products in a recall with no regard to the lot code, and that this is the most appropriate response in the event of a terrorist attack. In these comments' opinion, complex lot numbers may slow or substantially limit the recall of contaminated food. Additionally, requiring distributors to compromise the integrity of food packaging to determine lot codes defeats the purpose of the proposal. Some comments state that this requirement represents a disproportionate burden to packaged food distributors. Some comments state that food manufacturers may use independent delivery persons who pick up product from several manufacturers for delivery to retailers. There may be as many as 75 to 100 different products on each truck. The independent delivery person has no capability to capture the lot numbers of the products of several different manufacturers. (Response) (Response) The final rule does not require distributors to track lot/code numbers or other identifiers. DSD vendors will not be subject to the lot code requirement in § 1.345(a)(4) for activities other than manufacturing, processing, and packing food. Thus, activities such as holding and transportation are not subject to the requirements. (Comment 113) Many comments request clarifications for the terms 'other identifiers' and 'to the extent information this information exists.' (Response) FDA acknowledges that most firms use lot or code numbers to identify specific batches of their products. However, some may use other technologies such as barcodes. The term 'other identifier' is intended to capture any other methods that the food industry may be using to identify specific lots of product. FDA is mandating that this information be captured in the records, where required, to the extent this information exists. It is conceivable that certain sectors of the industry may not use lot or code numbers, or other identifiers to identify specific lots of products. In this case, the regulations do not specify that these sectors start using such identifiers. The identifiers are required only to the extent that they already exist. (Comment 114) A number of comments suggest that, in lieu of lot numbers, purchase orders numbers would serve as acceptable identifiers.

Number of Facilities with Approved Classified Storage (Of Over 12,000 NISP Cleared Facilities): 3658 A single, integrated, cohesive industrial security program to protect classified information and to preserve our Nation's economic and technological interests. Facilities Randomly Selected and

Responding to Data Collection: 1038 Maximum uniformity and consistency by contractors who support the Executive branch to effectively protect and safeguard classified information through all phases of the contracting process for any classified information an Agency releases to a contractor. Estimated Total NISP Security Costs for Facilities with Approved Classified Storage (With 95% Margin of Error to give 95% Upper Confidence Limit): \$1,413,150,249 + \$72,968,977 = \$1,486,119,226 Contractors must comply, when levied by the FAR security requirements clause or equivalent clauses in contracts involving access to classified information, with uniform procedures for the proper safeguarding of classified information to reduce the risk of unauthorized disclosure of classified information. Based on the data collected from the survey, we can be 95% confident the true 2017 total NISP security cost for contractor facilities with approved classified storage is less than \$1.486B. Assumptions and Notes: · Of over 12,000 NISP cleared facilities, 3,658 facilities are approved for classified storage and 1,038 responded to the survey. (printed page 83306) · Companies were selected at random according to survey methodology. · The applicable NISP CSA, based on a valid requirement for access to classified information (e.g., contract or bid), funds the costs for evaluating and processing a contractor for an entity eligibility determination (facility clearance) and the costs of personnel security vetting requirements for required access to classified information by any contractor employees. · The security cost profile for non-responding companies is assumed to be similar to that of responding companies. · Outlying survey data points were removed from data analysis. · Overall DoD contract spending for 2017 was \$331 billion; but DoD does not have such data for these contractor cleared facilities in the NISP for performance on contracts requiring access to classified information. · DoD has not collected security costs from those contractor cleared facilities that are not authorized to store classified information at their own contractor locations.

3.1.4 | Environment Condition Preparation ... 3.1.4 Environment Condition Preparation Environment condition refers to context information that is generally not associated with any specific subject or object but is required in the decision process.

Not a CSP CUI (with or without SPD) The CSP shall meet the FedRAMP requirements in 48 CFR 252.204-7012 The services provided by the ESP are in the OSA's assessment scope and shall be assessed as part of the OSA's assessment. SPD (without CUI) The services provided by the CSP are in the OSA's assessment scope and shall be assessed as Security Protection Assets The services provided by the ESP are in the OSA's assessment scope and shall be assessed as Security Protection Assets. Neither CUI nor SPD A service provider that does not process CUI or SPD does not meet the CMMC definition of an ESP A service provider that does not process CUI or SPD does not meet the CMMC definition of an ESP. (ii) The use of an ESP, its relationship to the OSA, and the services provided need to be documented in the OSA's SSP and described in the ESP's service description and customer responsibility matrix (CRM), which describes the responsibilities of the OSA and ESP with respect to the services provided. Note that the ESP may voluntarily undergo a CMMC certification assessment to reduce the ESP's effort required during the OSA's assessment. The minimum assessment type for the ESP is dictated by the OSA's DoD contract requirement. (d) CMMC Level 3 scoping. Prior to performing a Level 3 certification assessment, the CMMC Assessment Scope must be specified. (1) The CMMC Assessment Scope for Level 3 is based on the specification of asset categories and their respective requirements as set forth in table 5 to this paragraph (d)(1). Additional information is available in the guidance document listed in paragraph (g) of appendix A to this part. Table 5 to § 170.19 (d)(1) · CMMC Level 3 Asset Categories and Associated Requirements

Asset category	Asset description	OSC requirements	CMMC assessment requirements
Assets that are in the Level 3 CMMC Assessment Scope	Controlled Unclassified Information (CUI) Assets	Assets that process, store, or transmit CUI	Assets that can, but are not intended to, process, store, or transmit CUI (defined as Contractor Risk Managed Assets in table 1 to paragraph (c)(1) of this section CMMC Scoping).
	Document in the asset inventory	Document asset treatment in the System Security Plan (SSP).	Document in the network diagram of the CMMC Assessment Scope.
	Prepare to be assessed against CMMC Level 2 and Level 3 security requirements.	Limited check against Level 2 and assess against all Level 3 CMMC security requirements.	Security Protection Assets
	Assets that provide security functions or capabilities to the OSC's CMMC Assessment Scope, irrespective of whether or not these assets process, store, or transmit CUI	Document in the asset inventory	Document asset treatment in the SSP.
	Document in the network diagram of the CMMC Assessment Scope.	Prepare to be assessed against CMMC Level 2 and Level 3 security requirements.	

NoSQL systems can handle fast-paced agile development, the storage of large volumes of structured

and semi-structured data, the requirements for scale-out architecture, and modern application paradigms (e.g., microservices and real-time streaming) [MO]. However, they also face many challenges with regard to access control, such as a lack of proper authentication, encryption, dynamic model support, and fine-grained authorization (as described in Sec. 3.3). Therefore, careful considerations need to be made when implementing access control on NoSQL databases to address these issues effectively. Due to NoSQL's distributed nature, security becomes a more significant concern compared to central management-oriented RDBMS. From the perspective of data at rest and data in transit (i.e., communications between databases), NoSQL databases generally provide weaker security features when compared to RDBMS. The security of data in transit and communications in horizontally scaled NoSQL databases is a critical issue. Some systems use symmetric key algorithms to encrypt data based on the NoSQL structure (i.e., types). For example, in a key-value system, the value of the key is the encrypted data, including all of the other key values being concatenated and encrypted. When a query is created, the system retrieves data entities and then uses the symmetric key to decrypt the data [ZM]. As a result, the data is protected by encryption even if the key is intercepted while in transit between different NoSQL hosts.

) on the specific IT Strategy Goals and Objectives within FDA's Agency-wide IT Strategy. To facilitate comment, FDA has developed a series of questions in this section. The questions are not meant to be exhaustive, and FDA is also interested in any other pertinent information stakeholders would like to share on this topic. FDA encourages stakeholders to provide the specific rationale and basis for their comments, including any available supporting data and information.

1. Which goals and objectives are most important to you? Why?
2. Describe up to five ways the FDA IT Strategy will impact your industry?
3. What gaps do you see in the FDA IT Strategy's goals or objectives?
4. What challenges or risks do you foresee in executing the FDA IT Strategy?

III. FDA IT Strategy Goals and Objectives

Goal 1: Create a Shared OneFDA Ecosystem: Establish greater access to trusted data and shared resources across Centers, Offices, and external stakeholders. Encourage and facilitate cross-functional investment in technology to support enterprise business objectives for speed, scale, and value through robust Agency level governance processes, enhanced collaboration channels, and technology products and services. Shift FDA's culture to make sharing across Centers and Offices and with external stakeholders (where appropriate) the norm where prioritizing Agency-level public health outcomes improves results for everyone.

Objectives

Enhance Communication and Collaboration: Foster information and resource sharing with internal and external stakeholders to achieve both Agency and specific stakeholder outcomes, using a variety of communication channels to reach broader audiences. Enable collaboration and develop strong partnerships across Centers and Offices through integrated technologies and platforms.

Promote Transparency: Actively involve impacted stakeholders in IT solution planning, development, and execution to drive expected outcomes.

Optimize Investments: Align the diverse needs across FDA to the overarching strategy through stronger financial fidelity, enhanced budget coordination, and improved financial planning. Ensure effective IT resource utilization, transparency in IT budget allocation, and measurement of results achieved.

Strengthen Governance: Ensure the effective and efficient use of IT in enabling FDA to achieve mission outcomes through established standards, responsible procurement, and more robust decision-making and accountability mechanisms.

Goal 2: Strengthen IT Infrastructure:

Continue to modernize and secure the foundational IT infrastructure for all IT services and solutions. Proactively provide the ability to adapt to changes in workload demand, detect issues before they impact stakeholders, and quickly resolve technology issues to avoid disruptions to day-to-day operations.

Objectives

Provide Flexible Infrastructure Offerings:

(1) The SMO or other KMP are not appointed as the FSO or ITPSO. FSOs and ITPSOs may not be temporarily excluded. A cleared employee must always be appointed to fulfill the requirements of these positions in accordance with this rule. (2) An employee, cleared to the level of the entity eligibility determination, (printed page 83327) must be able to fulfill the NISP responsibilities of the temporarily excluded KMP in accordance with this rule while the temporary exclusion is in effect. (3) The applicable CSA may provide additional guidance on the duration of a temporary exclusion from access to classified information based on circumstances, business structure, and other relevant security information. (4) The contractor's governing board affirms the exclusion action, and provides a copy of the exclusion action to the CSA. The organization's governing body will document this action.

Table 1 to Paragraph (g)(4) Temporary Exclusion Resolutions

Type of affirmation	Language to be used in exclusion action
Affirmation for Temporary Exclusion from Access to Classified Information	Pending a final determination of eligibility for access to classified information by the U.S. Government, [insert name and position] will not

require, will not have, and can be effectively and formally excluded from access to all classified information disclosed to the entity. Affirmation for Temporary Exclusion from Higher Level Classified Information Pending a final determination of eligibility for access to classified information at the [insert SECRET or TOP SECRET] level, [insert name and position] will not have, and can be effectively and formally excluded from access to higher-level classified information [specify which higher level of information]. (h) Interim entity eligibility determinations. The CSA may make an interim entity eligibility determination for access to classified information, in the sole discretion of the CSA. See §.117.10(l) for access limitations that also apply to interim entity eligibility determinations. (i) An interim entity eligibility determination is made on a temporary basis pending completion of the full investigative requirements. (ii) If the contractor with an interim entity eligibility determination is unable or unwilling to comply with the requirements of this rule and CSA-provided guidance regarding the process to obtain a final entity eligibility determination, the CSA will withdraw the interim entity eligibility. (i) Multiple facility organizations. The home office must have an entity eligibility determination at the same level as the highest entity eligibility determination of an entity within the MFO. The CSA will determine whether branch offices are eligible for access to classified information if the branch offices need access and meet all other requirements. (j) Parent-subsidiary relationships. When a parent-subsidiary relationship exists, the CSA will process the parent and the subsidiary separately for entity eligibility determinations.

- Anti-forensics (e.g., obfuscation, data hiding, malware). Anti-forensics are a set of techniques used specifically to prevent or mislead forensic analysis. Anti-forensic challenges in cloud forensics include: - o The use of obfuscation, malware, data hiding, or other techniques to compromise the integrity of evidence - o Malware may circumvent virtual machine isolation methods - Incident first responders (e.g., trustworthiness of cloud Providers, response time, reconstruction). Incident first responder challenges in cloud forensics include: - o Confidence, competence, and trustworthiness of the cloud Providers to act as first responders and perform data collection - o Difficulty in performing initial triage - o Processing a large volume of collected forensic artifacts - Role management (e.g., data owners, identity management, users, access control). Role management challenges in cloud forensics include: - o Uniquely identifying the owner of an account - o Decoupling between cloud user credentials and physical users - o Ease of anonymity and creating fictitious identities online - o Determining exact ownership of data - o Authentication and access control - Legal (e.g., jurisdictions, laws, service level agreements, contracts, subpoenas, international cooperation, privacy, ethics) . Legal challenges in cloud forensics include: - o Identifying and addressing issues of jurisdictions for legal access to data - o Lack of effective channels for international communication and cooperation during an investigation - o Data acquisition that relies on the cooperation of cloud Providers, as well as their competence and trustworthiness - o Missing terms in contracts and service level agreements - o Issuing subpoenas without knowledge of the physical location of data - Standards (e.g., standard operating procedures, interoperability, testing, validation).

(2) If the contractor must use, have access to, or disseminate individually identifiable information subject to this part in order to perform any part of a contract, and the information would have been collected, maintained, used, or disseminated by the DoD Component but for the award of the contract, these contractor activities are subject to this part. (3) The restriction in paragraphs (a)(1) and (2) of this section do not apply to records: (i) Established and maintained to assist in making internal contractor management decisions, such as records maintained by the contractor for use in managing the contract; (ii) Maintained as internal contractor employee records even when used in conjunction with providing goods and services to the Department of Defense; or (iii) Maintained as training records by an educational organization contracted by a DoD Component to provide training when the records of the contract students are similar to and commingled with training records of other students (for example, admission forms, transcripts, academic counseling and similar records). (iv) Maintained by a consumer reporting agency to which records have been disclosed under contract in accordance with the Federal Claims Collection Act of 1966, 31 U.S.C. 3711(e) . (v) Maintained by the contractor incident to normal business practices and operations. (4) The DoD Components shall publish instructions that: (i) Furnish DoD Privacy Program guidance to their personnel who solicit, award, or administer Government contracts; (ii) Inform prospective contractors of their responsibilities, and provide training as appropriate, regarding the DoD Privacy Program; and (iii) Establish an internal system of contractor performance review to ensure compliance with the DoD Privacy Program. (b) Contracting procedures. The Defense Acquisition Regulations Council shall

develop the specific policies and procedures to be followed when soliciting bids, awarding contracts or administering contracts that are subject to this part. (c) Contractor compliance. Through the various contract surveillance programs, ensure contractors comply with the procedures established in accordance with § 310.12(b). (d) Disclosure of records to contractors. Disclosure of records contained in a system of records by a DoD Component to a contractor for use in the performance of a DoD contract is considered a disclosure within the Department of Defense (see § 310.21(b)). The contractor is considered the agent of the contracting DoD Component and to be maintaining and receiving the records for that Component. § 310.13 Safeguarding personal information. (a) General responsibilities.

HIPAA Security Rule section 164.312 (Technical Safeguards) addresses person or entity authentication. Covered entities and business associates must implement appropriate safeguards to protect electronic protected health information (ePHI). For person or entity authentication, organizations should: 1. Establish and document policies specific to person or entity authentication 2. Implement technical and procedural controls 3. Train workforce members on their responsibilities 4. Conduct periodic risk assessments addressing person or entity authentication 5. Maintain documentation of compliance efforts Under 45 CFR 164.312, this is a technical safeguards requirement that applies to all covered entities and business associates that create, receive, maintain, or transmit ePHI.

These controls are useful for recording and examining information system activity, especially when determining whether a security violation has occurred. [675] The Security Rule does not identify data that must be gathered by the audit controls or how often the audit reports should be reviewed. [676] Instead, a regulated entity must consider its risk analysis and organizational factors, such as current technical infrastructure and hardware and software security capabilities, to determine reasonable and appropriate audit controls for information systems that contain or use ePHI. [677] The audit controls standard has no implementation specifications. Section 164.312(c)(1), the standard for integrity, requires a regulated entity to implement policies and procedures to protect ePHI from improper alteration or destruction. The integrity of data can be compromised by both technical and non-technical sources. Workforce members or business associates may make accidental or intentional changes that improperly alter or destroy ePHI. Data can also be altered or destroyed without human intervention, such as by electronic media errors or failures. [678] The purpose of this standard is to establish and implement policies and procedures for protecting ePHI from being compromised regardless of the source. Improperly altered or destroyed ePHI can result in clinical quality problems for a covered entity, including patient safety issues. [679] Section 164.312(c)(2) contains the addressable implementation specification for the integrity standard that requires a regulated entity, when reasonable and appropriate, to implement electronic mechanisms to corroborate that ePHI has not been altered or destroyed in an unauthorized manner. To determine which electronic mechanisms should be implemented to ensure the integrity of ePHI, a regulated entity must consider the various risks to the integrity of ePHI identified during the risk analysis. Once a regulated entity has identified risks to the integrity of its data, it must identify security measures that will reduce the risks. [680] The standard for person or entity authentication at 45 CFR 164.312(d) requires a regulated entity to establish policies and procedures for verifying that a person seeking access to ePHI is the one claimed. This standard addresses technical controls for ensuring access is allowed only to those persons or software programs that have been granted access rights under the administrative safeguard for information access management at 45 CFR 164.308(a)(4) . This standard has no implementation specifications. Under the standard for transmission security at 45 CFR 164.312(e)(1) , a regulated entity is required to implement technical security measures to guard against unauthorized access to ePHI when transmitted electronically, such as through the internet. A regulated entity must identify the available and appropriate means to protect ePHI as it is transmitted, select appropriate solutions, and document its decisions. [681]

(iv) All requests for amendment must include all information necessary to make a determination on the request for amendment, as outlined in 32 CFR part 310, subpart D . (v) Requestors affiliated with the DoD may not use official government supplies or equipment to include mailing addresses, work phones/faxes, or DoD-issued email accounts to make requests for amendment. If requests are received using DoD equipment, the requestor will be advised to make a new request, using non-DoD equipment, and processing of their request will begin only after such new request is received. (3) When a request for amendment is received, the System Manager shall: (i) Mail a written

acknowledgement of the request for amendment to the individual within 10 working days of receipt. Such acknowledgement shall identify the request and may, if necessary, request any additional information needed to make a determination, advising the requestor that they have 20 calendar days to reply. No acknowledgement is necessary if the request can be reviewed and processed, to include notification to the individual of a grant or denial of amendment within the 10 working day period. Whenever practical, the decision to amend shall be made within 30 working days. For requests presented in person, written acknowledgement may be provided at the time the request is presented. (ii) Determine whether the requester has adequately supported his or her claim that the record is inaccurate, irrelevant, untimely, or incomplete. (A) If it is determined the individual's request for amendment is being granted, the System Manager will proceed to amend the records in accordance with existing statutes, regulations, or administrative procedures. The requestor will then be notified in writing of the agreement to amend and all previous holders of the records will be notified of the amendment as required by 32 CFR part 310, subpart D . (B) If it is determined that any, or all, of the record should not be amended, the original request, along with the record requested for amendment, and justification for recommended denial (printed page 24131) action shall be forwarded through their Director to the Chief of the OIP within 10 working days of receipt for a decision by the IDA. (C) If the request for an amendment pertains to a record controlled and maintained by another Federal agency, the amendment request shall be referred to the appropriate agency and the requestor will be notified in writing of the referral and contact information for the agency. (4) The Chief of the OIP will use the following procedures for any recommended denials of amendment: (i) The specific reason for denial of amendment cited by the System Manager shall be evaluated and a recommendation presented to the IDA on whether to support the recommendation to deny amendment to the record. (ii) If the request to amend the record is denied, a written letter will be sent to the requestor using procedures outlined in 32 CFR part 310, subpart D

(c) To qualify for the (j)(2) exemption, the system of records must be maintained by a DoD Component, or element thereof, that performs as its principal function any activity pertaining to the enforcement of criminal laws, such as the U.S. Army Criminal Investigation Command, the Naval Investigative Service, the Air Force Office of Special Investigations, and military police activities. However, where DoD offices perform multiple functions, but have an investigative component, such as the DoD Inspector General Defense Criminal Investigative Service or Criminal Law Divisions of Staff Judge Advocates Offices, the exemption may be claimed. Law enforcement includes police efforts to detect, prevent, control, or reduce crime, to apprehend or identify criminals; and the activities of military trial counsel, correction, probation, pardon, or parole authorities. (d) Information that may be protected under the (j)(2) exemption includes: (1) Records compiled for the purpose of identifying criminal offenders and alleged offenders consisting only of identifying data and notations of arrests, the nature and disposition of criminal charges, sentencing, confinement, release, parole, and probation status (so-called criminal history records); (2) Reports and other records compiled during criminal investigations, including supporting documentation. (3) Other records compiled at any stage of the criminal law enforcement process from arrest or indictment through the final release from parole supervision, such as pre-sentence and parole reports. (e) The (j)(2) exemption does not apply to: (1) Investigative records prepared or maintained by activities without primary law-enforcement missions. It may not be claimed by any activity that does not have law enforcement as its principal function except as indicated in paragraph (c) of this section. (2) Investigative records compiled by any activity concerning employee suitability, eligibility, qualification, or for individual access to classified material regardless of the principal mission of the compiling DoD Component. §-310.29 Specific exemptions. (a) Use of specific exemptions. The specific exemption established by 5 U.S.C. 552a(k) of the Privacy Act may be claimed to protect records that meet the following criteria (parenthetical references are to the appropriate subsection of the Act: (1) (k)(1). Information subject to 5 U.S.C. 552(b)(1) , (DoD 5200.1-R) (see also paragraph (c) of this section). (2) (k)(2).

(2) Contractors will establish and apply a graduated scale of administrative and disciplinary actions in the event of employee security violations or negligence in the handling of classified information. CSAs may provide guidance to contractors with examples of administrative or disciplinary actions that the contractor may consider implementing in the event of employee violations or negligence. Contractors are required to submit a final report to the CSA with the findings of an employee's culpability and what corrective actions were taken. (3) Contractors will include a statement of the administrative or disciplinary actions taken against an employee in a final report to the CSA. A statement must be included when the individual responsible for a security

violation can be determined. Contractors' final reports will indicate whether one or more of the following factors are evident: (i) Involved a deliberate disregard of security requirements. (ii) Involved negligence in the handling of classified material. (iii) Was not deliberate in nature but reflects a recent or recurring pattern of questionable judgment, irresponsibility, negligence, or carelessness. (f) CDC cyber incident reports. This paragraph applies only to CDCs and sets forth reporting requirements pursuant to 10 U.S.C. 391 and 393 and Defense Federal Acquisition Regulation Supplement Clause 252.204-7012. The reporting requirements of paragraph (f) of this section are in addition to the requirements in paragraphs (b) and (d) of this section, which can include certain activities occurring on unclassified information systems. DoD will provide detailed reporting instructions for contractors affected by these references via industrial security letter in accordance with DoDI 5220.22. (1) Reports to be submitted to the designated DoD CSO. CDCs will immediately report to the DoD CSO, any cyber incident on a classified covered information system that has been approved by that CSO to process classified information. (i) At a minimum, the report will include: (A) A description of the technique or method used in the cyber incident. (B) A sample of the malicious software involved in the cyber incident, if discovered and isolated by the CDC, (C) A summary of information in connection with any DoD program that has been potentially compromised due to the cyber incident. (ii) Information that is reported by the CDC (or derived from information reported by the CDC) will be safeguarded, used, and disseminated in a manner consistent with DoD procedures governing the handling of such information pursuant to Public Law 112-239 and 10 U.S.C. 391. (iii) Reports involving classified foreign government information will be reported to the Director, Defense Technology Security Administration (DoD). (2) Reports on non-Federal information systems not authorized to process classified information. CDCs will report cyber incidents on non-Federal, unclassified information systems in accordance with contract requirements. (3)

It is the vehicle for disseminating security information that the workforce, including managers, needs to do their jobs. These programs will ensure that personnel at all levels of the organization understand their information security responsibilities to properly use and protect the information resources entrusted to them. Awareness is a blended solution of activities that promotes security, establishes accountability, and informs the workforce of security news. Training strives to produce relevant and needed security knowledge and skills within the workforce. Training supports competency development and helps personnel understand and learn how to perform their security role. Education integrates all of the security skills and competencies of the various functional specialties into a common body of knowledge and adds a multidisciplinary study of concepts, issues, and principles (technological and social). NIST SP 800-50, Building an Information Technology Security Awareness and Training Program | Information Security Governance | The purpose of information security governance is to ensure that agencies are proactively implementing appropriate information security controls to support their mission in a cost-effective manner, while managing evolving information security risks. Information security governance has its own set of requirements, challenges, activities, and types of possible structures. Information security governance also has a defining role in identifying key information security roles and responsibilities, and it influences information security policy development and oversight and ongoing monitoring activities.

Congress gave FDA the discretion to issue regulations regarding the establishment and maintenance of records under section 306 of the Bioterrorism Act. Charitable food establishments, such as food banks, stand in place of the consumer and FDA will treat them as consumers for purposes of this final rule. Therefore, grocery stores, catering facilities, and others giving a charitable donation of food to a food bank, soup kitchen, or other similar charitable entity are not required to keep records of the immediate subsequent recipients of the food, and the charitable food establishment does not need to keep records of the immediate previous sources of that food or the immediate subsequent recipients of that food. FDA has determined that it does not need records of food donated to food banks to address credible threats of serious adverse health consequences or death to humans or animals. In the event of a traceback investigation, FDA believes that it is likely to have the ability to trace the immediate previous source of contaminated food by other means. Unless the source of the contamination is at the food bank itself, other consumers of that same food obtained from a grocery store are likely to identify that grocery store as a link in the chain-of-distribution of the contaminated product. In the case of a trace forward investigation, records will likely exist from the donor of the food to the charitable food establishment. FDA believes that the likelihood of the existence of such records is great given the tax benefits available to the persons donating goods to establishments that are 501(c)(3) establishments under the Internal Revenue Code.

Therefore, FDA does not believe that exempting such charitable entities from these requirements would interfere with the goals of the Bioterrorism Act or subpart J of this final rule. With respect to the ·reclamation centers· mentioned by the comment, FDA understands that most reclamation centers are actually owned by the (printed page 71579) grocery store or grocery chain. Such reclamation centers will be treated as if they are part of the grocery store and must keep the records that must be kept by the grocery store. For instance, if food from the reclamation center is donated to a food bank, the exclusion described previously applies. If food is sold to consumers, the exclusion for foods sold directly to consumers applies. If food is returned to the manufacturer, or sold to another nonconsumer, the reclamation center must keep records of the immediate subsequent recipients of food, to the extent this information is reasonably available.

that the information contained within the financial statements complies with GAAP in all material respects. Therefore, in order to improve the clarity of the final rule, the requirement for compliance with GAAP in order to receive PBPs is now applied to ·the contractor's financial statements· rather than ·the output of the contractor's accounting system· (see 232.1003-70 and 252.232-7015). c. Representation is unnecessary. Comment: One respondent stated that the proposed representation at DFARS 252.232-7015 with regard to compliance with GAAP is unnecessary, since costs incurred have no bearing on the amounts billed under PBPs. Response: The fact that incurred costs no longer have bearing on the amounts billed under PBPs has no relevance to the requirement for representation by the offeror that its financial statements are, or are not, in compliance with GAAP. Section 831, as codified at 10 U.S.C. 2307(b)(4) , requires compliance with GAAP in order to receive performance-based payments. Providing a representation is one of the least burdensome ways to demonstrate compliance with GAAP. 4. Reporting of Incurred Costs Most respondents had objections to the continued requirement for reporting of incurred costs in the clauses at (printed page 19684) DFARS 252.232-7012 and 252.232-7013. a. Requirement for Government-unique accounting system. Comment: One respondent noted that 10 U.S.C. 2307 expressly states that the Secretary of Defense shall ensure that nontraditional defense contractors and other private sector companies are eligible for performance-based payments and that there shall be no requirements for a contractor to develop Government-unique accounting systems or practice as a prerequisite for agreeing to receive PBPs. Some respondents believed that retention of the requirement to report cumulative contract costs incurred to date, as a condition of receiving PBPs, imposes a requirement to develop a Government-unique accounting system, and therefore is inconsistent with 10 U.S.C. 2307(b)(4)(A) , as amended by section 831. For example, one respondent stated that the cost reporting in the proposed rule would require a Government-unique job order cost accounting system to generate FAR- and DFARS-compliant cost reports. Response: The reporting of incurred costs does not require a Government-unique cost accounting system. Systems that identify costs with the projects for which they are incurred (·job costing·, as a broad term) are not at all unique to Government requirements. It would be highly unlikely for a fiscally sound company to have no means of identifying the costs of performing a contract. Furthermore, the rule does not require any particular accounting system; rather, the rule states that ·incurred cost is determined by the Contractor's accounting books and records·. Comment:

DoD considered many alternatives before deciding which NIST SP 800-172 Feb2021 requirements to include as part of CMMC Level 3. NIST SP 800-172 Feb2021 notes that ·There is no expectation that all of the enhanced security requirements will be selected by Federal agencies implementing this guidance·. For a variety of reasons, including DoD's estimation of cybersecurity maturity and complexity across the DIB, and potential cost of certain Level 3 requirements compared with the benefit, the DoD has included a limited set of NIST SP 800-172 Feb2021 requirements. On a contract-by-contract basis, additional requirements may be added. OSAs are at liberty to implement additional requirements. The intent of AC.L3-3.1.2e, which requires restricted access to systems and system components, is not that DIB companies issue laptops to external users wishing to access Level 3 enclaves. While laptop issuance is one solution, other options are available. The important concept in this requirement is ·comply to connect·, and it applies to all users, both within the OSA and externally, equally. In complying with this requirement, GFE may be considered provisioned by the OSC and therefore is not restricted under that requirement. DoD defines the ODPs for NIST SP 800-172 Feb2021 included in CMMC Level 3. This eliminates the risk of different parameters being set for different DoD programs. Rulemaking requirements dictate that table 1 to 170.14(c)(4) be codified in the rule. The Assessment Guide is an optional document. DoD declines to accept the risk of removing security requirement CM.L3-3.4.2e. The Assessment Guide has been updated to include additional discussion on this security requirement. Feedback on individual security requirements

should be direct to NIST. Any relationship to the NIST SP 800-53 R5 controls is for information only. The requirements that must be implemented for CMMC Level 3 are defined in the rule table 1 to § 170.14(c)(4). IA:L3-3.5.3e and CM:L2-3.4.7 are different requirements. The L2 requirement is about functionality, and the L3 requirement is about trust. Feedback on individual security requirements should be direct to NIST. 24. CMMC Annual Affirmation Requirements Comment: One commenter recommended the affirmation statement include a statement confirming the scope has not changed and requested the rule be modified to identify types of changes that would constitute a change of system scope. Another commenter recommended removing any requirement for affirmation after assessment certificate issuance or else revising the rule to identify any benefits the affirmation provides that conducting an independent assessment does not already provide. Another commenter recommended the DoD clarify that out-of-cycle affirmations are not needed.

Personnel investigations and vetting records may contain evaluation material used to determine potential for promotion in the armed services. In some cases, such records may contain information pertaining to the identity of a source who furnished information to the Government under an express promise that the source's identity would be held in confidence (or prior to the effective date of the Privacy Act, under an implied promise). Application of exemption (k)(7) for such records may be necessary because access to, amendment of, or release of the accounting of disclosures of such records could identify these confidential sources who might not have otherwise come forward to assist the Government, hinder the Government's ability to obtain information from future confidential sources, and result in an unwarranted invasion of the privacy of others. Amendment of such records could also impose a highly impracticable administrative burden by requiring investigations to be continuously reinvestigated. (B) Subsections (d)(3) and (4). These subsections are inapplicable to the extent an exemption is claimed from (d)(1) and (2). Moreover, applying the (printed page 14736) amendment appeal procedures toward background investigation and vetting records could impose a highly impracticable administrative burden by requiring investigations to be continuously reinvestigated. (C) Subsection (e)(1). In the collection of information for authorized vetting purposes, it is not always possible to conclusively determine the relevance and necessity of particular information in the early stages of the investigation or adjudication. In some instances, it will be only after the collected information is evaluated in light of other information that its relevance and necessity for effective investigation and adjudication can be assessed. Collection of such information permits more informed decision-making by the Department when making required suitability, eligibility, fitness, and credentialing determinations. Accordingly, application of exemptions (k)(1), (k)(2), (k)(3), (k)(5), (k)(6), and (k)(7) may be necessary. (iv) Exempt records from other systems. In addition, in the course of carrying out personnel vetting, including records checks for continuous vetting, exempt records from other systems of records may in turn become part of the records maintained in this system. To the extent that copies of exempt records from those other systems of records are maintained into this system, the DoD claims the same exemptions for the records from those other systems that are entered into this system, as claimed for the original primary system of which they are a part. § 310.14 Department of the Air Force exemptions. (a) All systems of records maintained by the Department of the Air Force shall be exempt from the requirements of 5 U.S.C. 552a(d) pursuant to 5 U.S.C. 552a(k)(1) to the extent that the system contains any information properly classified under Executive Order 12958

(ii) Upon receipt of changes to the SF 328 from contractors, DSS will assess the changes to determine if they are material; if they require the imposition of new FOCI mitigation or modification of existing FOCI mitigation; or if they warrant the termination of existing FOCI mitigation. DSS will periodically review the definition of material change with regard to FOCI and publish updated guidance as to what constitutes a reportable material change in coordination with OUSD(I) Security Directorate. (13) Limited FCL. (i) A Limited FCL may be an option for a single, narrowly defined purpose when there is foreign ownership or control of a U.S. company. In that respect, a Limited FCL is similar to an LAA for a non-U.S. citizen. Consideration of a Limited FCL includes a DSS determination that the company is under FOCI and that the company is either unable or unwilling to implement FOCI negation or mitigation. A GCA or a foreign government may sponsor a (printed page 19477) Limited FCL consistent with the provisions of paragraphs (b)(13)(iii)(A) through (b)(13)(iii)(D) of this section. (ii) DSS will: (A) Document the requirements of each Limited FCL, including the limitations of access to classified information. (B) Verify a Limited FCL only to the sponsoring GCA or foreign government. (C) Ensure, in accordance with paragraph (b)(7) of this section, that the contractor has and implements a TCP consistent with DoD 5220.22-M.

(D) Process a home office along with a branch or division, when the GCA or foreign government sponsors the branch or division for a Limited FCL and ensure that the limitations of the Limited FCL are applied to the home office as well as the branch or division. (E) Administratively terminate the Limited FCL when the FCL is no longer required. (iii) There are four types of Limited FCLs: (A) A GCA may sponsor a joint venture company established in the United States for the purpose of supporting a cooperative arms program involving DoD. An authorized GCA official, at the PEO level or higher, must certify in writing that the classified information to be provided to the company has been authorized for disclosure to the participating governments in compliance with U.S. National Disclosure Policy NDP-1, 'National Policy and Procedures for the Disclosure of Classified Military Information to Foreign Governments and International Organizations,' (available to designated disclosure authorities on a need-to-know basis from the Office of the Deputy Under Secretary of Defense for Policy Integration and Chief of Staff to the Under Secretary of Defense for Policy). Key management personnel (KMPs) and employees may be citizens of the countries of ownership, if DSS is able to obtain security assurances. The non-U.S. citizens retain their foreign government issued personnel security clearances. The company FSO must be a cleared U.S. citizen as set forth in DoD 5220.22-M.

(definition of 'Facility'). Back to Citation 377. 45 CFR 164.306 . Back to Citation 378. See, e.g., Steve Alder, '\$8.9 Million Banner Health Data Breach Settlement Gets Final Approval,' The HIPAA Journal (Apr. 27, 2020), <https://www.hipaajournal.com/8-9-million-banner-health-data-breach-settlement-gets-final-approval/> (describing a settlement to cover claims stemming from an attack on a health system's payment processing system used in the food and beverage outlets of its hospitals). Back to Citation 379. 63 FR 8334 , 8340 (Feb. 20, 2003). Back to Citation 380. 45 CFR 164.308(a)(1)(i)(A) . Back to Citation 381. 45 CFR 164.308(a)(1)(i)(B) . Section 164.306(a) requires regulated entities to comply with four general requirements to protect ePHI. Back to Citation 382. . See NIST definition of 'risk,' Glossary, Computer Security Resource Center, National Institute of Standards and Technology, U.S. Department of Commerce (citing William Newhouse, et al., 'Multifactor Authentication for E-Commerce,' NIST Special Publication 1800-17, National Institute of Standards and Technology, U.S. Department of Commerce (July 2019)), <https://csrc.nist.gov/glossary/term/risk> . Back to Citation 383. 45 CFR 164.304(b)(2)(iv) . Back to Citation 384. 45 CFR 164.308(a)(1)(ii)(A) ; proposed 45 CFR 164.308(a)(2)(i) . Back to Citation 385. 45 CFR 164.304 (definition of 'Security or Security measures'). Back to Citation 386. 45 CFR 164.304 (definition of 'Security or Security measures'). Back to Citation 387. See NIST definition of 'firewall,' Glossary, Computer Security Resource Center, National Institute of Standards and Technology, U.S. Department of Commerce, <https://csrc.nist.gov/glossary/term/firewall> . Back to Citation 388. See generally University of Texas M.D. Anderson Cancer Center, *supra* note 258, p. 478. Back to Citation 389. . For example, in the 2003 Final Rule, we explained that in developing technical safeguards, the Department proposed technical security services requirements and specific technical security mechanisms with implementation specifications without carving out or limiting these items to policies and procedures about the requirements. See 68 FR 8334 , 8354 (Feb. 20, 2003). Back to Citation 390. 45 CFR 164.304 (definition of 'Technical safeguards'). Back to Citation 391. 'Proposed 45 CFR 164.308(a)(2)(ii)(A) (2). Back to Citation 392. . See NIST definition of 'threat,' Glossary, Computer Security Resource Center, National Institute of Standards and Technology, U.S. Department of Commerce, <https://csrc.nist.gov/glossary/term/threat> . Back to Citation 393. . See 45 CFR 160.502 of the 2003 interim final rule, 68 FR 18895 , 18898 (Apr. 17, 2003). Back to Citation 394. 45 CFR 160.103 (definition of 'Person'). Back to Citation 395. 45 CFR 164.304 (definition of 'User'). Back to Citation 396. . See 'Defending Against Common Cyber-Attacks,' Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Mar. 2022),

1. The system administrator shall ensure that the organization's security policy is enforced.
2. Key recovery procedures shall be in place to ensure that users can recover their data if they lose their authentication information (password, token data, etc). A method for data recovery personnel to authenticate these users should be in place prior to the recovery of the user's keys or files.
3. If the EFS includes a master administrator password for use in data recovery by the system administrator, the system administrator shall utilize a strong password.
4. System administrators shall provide training and security guidance to the end users of the system that, at a minimum, focuses on passwords, data-recovery procedures, and user configuration of their system to utilize the authentication features within the system.

One commenter recommended that both the sharing of CUI and the decision to apply a CMMC compliance assessment should only be considered for contracts of sufficient contract value and performance period to make the expense of safeguarding CUI worthwhile. This commenter asserted that small businesses are selected for SBIR contract award not based on ability to protect information, but instead on the unique product or service they offer. Some commenters expressed concern that CMMC could result in state-funded universities incurring costs to comply with CMMC level 2, while even the costs for implementing required FCI safeguarding requirements is a significant financial burden. These commenters speculated that applying FCI or CUI markings to fundamental research information negatively impact academic institutions by requiring them to remove such data from the public domain. This commenter cited DFARS clause 252.204-7000 as rationale to modify the CMMC rule to exclude fundamental research. One commenter requested that when contracting for fundamental research, the Government include a CMMC requirement based only on whether information shared is currently FCI or (printed page 83114) CUI, and not whether the effort might lead to development of FCI or CUI. Another commenter requested that DoD issue policies clearly describing how to recognize or identify circumstances that could result in fundamental research becoming FCI or CUI such that it would require being processed, stored, or transmitted on CMMC compliant information systems. The commenter expressed concern that absent such policies, research institutions may house all DoD-related project activities in CUI enclaves ·out of an abundance of caution·, thereby unnecessarily expanding CUI applicability at significant cost. They asked that DoD Instruction 5200.48, ·Controlled Unclassified Information·, and a related DoD policy memorandum ·Clarifying Guidance for Marking and Handling Controlled Technical Information in accordance with Department of Defense Instruction 5200.48, `Controlled Unclassified Information· be incorporated into the rule by reference. One commenter questioned whether and how CMMC requirements may apply to non-contract efforts, including grants, or efforts conducted under Other Transactional Authorities. Response: One of the main purposes of the CMMC Program is to ensure that DoD contracts that require contractors to safeguard CUI will be awarded to contractors with the ability to protect that information. All contractor-owned information systems that process, store, or transmit CUI are subject to the requirements of NIST SP 800-171 when DFARS clause 252.204-7012 is included in the contract. This is the case whether or not the contractor is engaged in fundamental research.

Under the right of access, an individual who is the subject of PHI has the right to inspect and request a copy of PHI about them in a designated record set, subject to certain exceptions. A regulated entity is required to provide such access in the form and format requested by the individual, if it is readily producible in such form and format. Thus, if an individual requests that the regulated entity provide them access in a manner that does not support encryption, a regulated entity is generally required to do so if it does not jeopardize the security of the regulated entity's information systems. For the exception to apply, a regulated entity would be required to have informed the individual of the risks associated with the transmission, receipt, and storage of unencrypted ePHI when the individual requests unencrypted access and to document that the individual has been informed of such risks. [738] Consistent with the information blocking regulations, the information provided by regulated entities that are also actors must: focus on any current privacy and/or security risks posed by the technology or the third-party developer of the technology; be factually accurate, unbiased, objective, and not unfair or deceptive; and be provided in a non-discriminatory manner. [739] For example, a regulated entity that is an actor must provide information to individuals about the privacy and security risks of all mobile health applications in the same manner. We are not proposing to require that the documentation be in any particular form or format. Rather, the required information could be on a standard form, chart note, or checkbox, as examples. The Department does not propose to apply this exception to ePHI transmitted in other forms or formats, such as on a CD or other physical device used to maintain and transmit ePHI. The proposal would not absolve a regulated entity from compliance with other applicable laws or regulations, including the information blocking regulations. [740] We recognize that emergencies or other occurrences may render it infeasible to encrypt ePHI. Thus, the third proposed exception at 45 CFR 164.312(b)(3)(iii) would apply to certain circumstances in which encryption is infeasible. Such circumstances would be limited to when there is emergency or other occurrence that adversely affects a regulated entity's relevant electronic information systems. For the proposed exception to apply, a regulated entity would be required to implement reasonable and appropriate compensating controls in accordance with and determined by its contingency plan. [741]

Incorporation by reference. 170.3 Applicability. 170.4 Acronyms and definitions. 170.5 Policy. Subpart B-Government Roles and Responsibilities. 170.6 CMMC PMO. 170.7 DCMA DIBCAC. Subpart C-CMMC Assessment and Certification Ecosystem. 170.8 Accreditation Body. 170.9 CMMC Third-Party Assessment Organizations (C3PAOs). 170.10 CMMC Assessor and Instructor Certification Organization (CAICO). 170.11 CMMC Certified Assessor (CCA). 170.12 CMMC Certified Instructor (CCI). 170.13 CMMC Certified Professional (CCP). Subpart D-Key Elements of the CMMC Program. 170.14 CMMC model. 170.15 CMMC Level 1 Self-Assessment and Affirmation requirements. 170.16 CMMC Level 2 Self-Assessment and Affirmation requirements. 170.17 CMMC Level 2 Certification Assessment and Affirmation requirements. 170.18 CMMC Level 3 Certification Assessment and Affirmation requirements. 170.19 CMMC scoping. 170.20 Standards acceptance. 170.21 Plan of Action and Milestones requirements. 170.22 Affirmation. 170.23 Application to subcontractors. 170.24 CMMC scoring methodology. Appendix A to Part 170-Guidance Authority: 5 U.S.C. 301 ; Sec. 1648, Pub. L. 116-92 , 133 Stat. 1198. Subpart A-General Information. §170.1 Purpose. (a) This part describes the Cybersecurity Maturity Model Certification (CMMC) Program of the Department of Defense (DoD) and establishes policy for requiring defense contractors and subcontractors to implement prescribed cybersecurity standards for safeguarding: Federal Contract Information (FCI), and Controlled Unclassified Information (CUI), as well as conduct an assessment of contractor information systems that process, store, or transmit FCI or CUI; provide security protections for such CUI systems; or are not logically or physically isolated from all such CUI systems, for compliance with the applicable prescribed cybersecurity standard. (b) The CMMC Program is designed to enhance protection of FCI and CUI when it is processed, stored, or transmitted on defense contractor information systems to meet evolving threats and safeguard the sensitive unclassified information that supports and enables the warfighter. The CMMC Program provides a consistent methodology to assess a defense contractor's implementation of required cybersecurity requirements. The CMMC Program utilizes the security standards set forth in the Federal Acquisition Regulation (FAR) clause 52.204-21; National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 Rev 2; and selected requirements from the NIST SP 800-172, as applicable (see table 1 to §170.14(c)(4) CMMC Level 3 Requirements). (c) The CMMC Program provides DoD with a viable means of conducting the volume of assessments necessary to verify contractor and subcontractor implementation of required cybersecurity requirements.

The results of a risk analysis, performed in accordance with the proposed standard for risk analysis, generally provide the regulated entity with a list of applicable threat/vulnerability pairs as well as the overall risk rating of each pair to the confidentiality, integrity, and availability of ePHI. [504] For example, some threat/vulnerability pairs may result in a risk rating of moderate or high level of risk to ePHI, while other pairs may result in a risk rating of low level of risk. The regulated entity would need to determine what risk rating poses an unacceptable level of risk to ePHI and address any threat/vulnerability pairs that indicate a risk rating above the organization's risk tolerance. [505] Under this proposed standard, the regulated entity would be required to reduce the risks to its ePHI to a level that is reasonable and appropriate for its specific circumstances. Ultimately, the regulated entity's risk assessment processes should inform its decisions about the manner in which it will implement security measures to comply with the Security Rule's standards and implementation specifications. [506] Additionally, each regulated entity would be required to document the security controls it has implemented because it has determined them to be reasonable and appropriate, including analyses, decisions, and the rationale for decisions made to refine or adjust the security controls. [507] As stated by NIST, the documentation and retention of risk assessment and risk management activities is important for future risk management efforts. [508] In general, risk management activities should be performed with regular frequency to examine past decisions, reevaluate risk likelihood and impact levels, and assess the effectiveness of past remediation efforts. [509] Risk management plans should address risk appetite, risk tolerance, workforce duties, responsible parties, the frequency of risk management, and required documentation. [510] h. Section 164.308(a)(6)(i)-Standard: Sanction Policy Consistent with other proposals to elevate certain critical implementation specifications to standards, we propose to elevate the implementation specification for sanction policy at 45 CFR 164.308(a)(ii)(C) to a standard for sanction policy at proposed 45 CFR 164.308(a)(6)(i) . We propose this standard because applying appropriate sanctions against workforce members who fail to comply with security requirements, and thus imperil the (printed page 945) security of ePHI, serves as an important tool for improving compliance by other workforce members with the regulated entity's safeguards for ePHI. While the Department does not propose to modify the language of the standard, we are proposing three

implementation specifications that are consistent with guidance that was previously issued by the Department. Specifically, under the proposed implementation specification for policies and procedures at proposed 45 CFR 164.308(a)(6)(ii)(A)

One comment asks for clarification on the contents of the System Security Plan when documenting the use of an ESP. Two comments ask how to assess an OSA that is using a CSP to store CUI that does not meet the FedRAMP requirements. One comment asks how C3PAOs can check on the assessment status of an ESP. Three comments ask how to avoid redundant assessments of ESPs. One comment asks to clarify how to handle ESPs at Level 3 with respect to requirement AC.L3-3.1.2e that restricts access to systems that are owned, provisioned, or issued by the organization. One comment recommends DoD exempt CSPs that provide service with end-to-end encryption from CMMC requirements, similar to a common carrier. Several comments inquired about guidelines and practices for obtaining Customer Responsibility Matrices (CRM) from CSPs and suggest the rule be modified to also require them from ESPs. One comment asks about how to obtain a CSP's System Security Plan. Response: Implications for OSAs and C3PAOs for using non-compliant ESPs are adequately addressed in the rule. The CMMC compliance of an ESP, including a CSP, falls under the OSA's assessment. If an ESP is used to meet any of the CMMC requirements for the OSA, then the ESP is part of the scope of the OSA's assessment, and the compliance of the ESP will be verified. An ESP that is seeking CMMC assessment will need to obtain a CAGE code and an account in SPRS to enable the reporting of its assessment results via CMMC eMASS. A SPRS account is required to complete the CMMC annual affirmation requirement included in DoD contracts that include a CMMC certification requirement. An ESP that processes, stores, or transmits CUI, is an extension of the OSA's environment. As part of that environment, the ESP will be assessed against all requirements and accountable for all users who have access to CUI as part of the ESP's service, not just OSA employees. The government cannot comment on specific implementation or documentation choices of an OSA, including the use of an ESP. The C3PAO can only give credit to a FedRAMP Moderate Authorized or equivalent CSP. Any requirements dependent on contributions from a CSP in any other stage of compliance are considered NOT MET. The requirements in the rule for FedRAMP Moderate equivalency have been updated to reflect DoD policy. OSAs can consider CSPs in the FedRAMP process for equivalency if they meet the requirements in DoD policy. An ESP that is a CSP will be listed on the FedRAMP Marketplace. An ESP that is not a CSP and processes, stores, or transmits CUI will be within the OSA's assessment scope. An ESP can also volunteer to have a C3PAO assessment and could make that information available to the OSA.

Develop a written inventory of the covered entity's or business associate's technology assets that contains the identification, version, person accountable, and location of each technology asset. (B) Network map. Develop a network map that illustrates the movement of electronic protected health information throughout the covered entity's or business associate's electronic information systems, including but not limited to how electronic protected health information enters and exits such information systems, and is accessed from outside of such information systems. (C) Maintenance. Review and update the written inventory of technology assets required by paragraph (a)(1)(ii)(A) of this section and the network map required by paragraph (a)(1)(ii)(B) of this section in the following circumstances: (1) On an ongoing basis, but at least once every 12 months. (2) When there is a change in the covered entity's or business associate's environment or operations that may affect electronic protected health information, including but not limited to the adoption of new technology assets; the upgrading, updating, or patching of technology assets; newly recognized threats to the confidentiality, integrity, or availability of electronic protected health information; a sale, transfer, merger, or consolidation of all or part of the covered entity or business associate with another person; a security incident that affects the confidentiality, integrity, and availability of electronic protected health information; and relevant changes in Federal, State, Tribal, or territorial law. (2) Standard: Risk analysis ·(i) General. Conduct an accurate and comprehensive written assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of all electronic protected health information created, received, maintained, or transmitted by the covered entity or business associate. (ii) Implementation specifications ·(A) Assessment. The written assessment must include, at a minimum, all of the following: (1) A review of the technology asset inventory required by paragraph (a)(1)(ii)(A) of this section and the network map required by paragraph (a)(1)(ii)(B) of this section to identify where electronic protected health information may be created, received, maintained, or transmitted within the covered entity's or business associate's electronic information systems. (2) Identification of all reasonably anticipated threats to the confidentiality, integrity, and availability of electronic protected health information that the

covered entity or business associate creates, receives, maintains, or transmits. (3)
Identification of potential vulnerabilities and predisposing conditions to the covered entity's or
business associate's relevant electronic information systems. (4

502. · See ·6 Basics of Risk Analysis and Risk Management,· HIPAA Security Series, Volume 2,
Paper 6, Centers for Medicare & Medicaid Services (June 2005, revised Mar. 2007), <https://www.hhs.gov/sites/default/files/ocr/privacy/hipaa/administrative/securityrule/riskassessment.pdf?language=es> . Back to Citation 503. · See ·Implementing the Health Insurance Portability and
Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461. Back
to Citation 504. See id. at 18. Back to Citation 505. See id. at 25. Back to Citation 506.
Id. Back to Citation 507. · See proposed 45 CFR 164.306(d) and 164.316(b)(1) . Back to
Citation 508. · See ·Implementing the Health Insurance Portability and Accountability Act
(HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461, p. 27. Back to Citation
509. See id. at 31. Back to Citation 510. See id. Back to Citation 511. ·The 2024 Study
on Cyber Insecurity in Health Care: The Cost and Impact on Patient Safety and Care,· supra note
143, p. 7. Back to Citation 512. · See ·How Sanction Policies Can Support HIPAA Compliance,·
Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services
(Oct. 2023), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-october-2023/index.html#ftn10> . Back to Citation 513. 68 FR 8334 , 8347 (Feb. 20,
2003). Back to Citation 514. 65 FR 82462 , 82747 (Dec. 28, 2000). Back to Citation 515. 68
FR 8334 , 8347 (Feb. 20, 2003). Back to Citation 516. 65 FR 82462 , 82562 (Dec. 28, 2000).
Back to Citation 517. · See ·Security Standards: Administrative Safeguards,· HIPAA Security
Series, Volume 2, Paper 2, Centers for Medicare & Medicaid Services (May 2005, revised Mar. 2007),
<https://www.hhs.gov/sites/default/files/ocr/privacy/hipaa/administrative/securityrule/adminsafeguards.pdf> ; see also ·Implementing the Health Insurance Portability and Accountability Act
(HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461, p. 33. Back to Citation
518. ·Records of sanction activity should be retained for at least six years. See 45 CFR
164.316 and 164.530(e)(2) . Back to Citation 519. · See 65 FR 82462 , 82562 (Dec. 28,
2000). Back to Citation 520. Id. Back to Citation 521. Id. Back to Citation 522. · See
·Security Standards: Administrative Safeguards,· supra note 517. Back to Citation 523. · See
45 CFR 164.308(a)(1)(ii)(C) , 164.530(e)(1) ; see also 65 FR 82462 , 82747 (Dec. 28, 2000)
(·All members of a covered entity's workforce are subject to sanctions for violations.·). Back to
Citation 524. ·Workstations may also be referred to as ·endpoints.· See ·Memorandum on
Improving Detection of Cybersecurity Vulnerabilities and Incidents on Federal Government Systems
through Endpoint Detection and Response,· Office of Management and Budget, Executive Office of the
President, p. 1 (Oct. 8, 2021) <https://www.whitehouse.gov/wp-content/uploads/2021/10/M-22-01.pdf> . Back to Citation

(2) Performed to support research or statistical projects. Personally identifying data can be used
for purposes of conducting the match and the match results may contain identifying data about
individuals. However, the match results shall not be used to make a decision that affects the
rights, benefits, or privileges of specific individuals. (3) Performed by an agency, or a component
thereof, whose principal function is the enforcement of criminal laws, subsequent to the initiation
of a specific criminal or civil law enforcement investigation of a named individual or individuals.
(i) The match must flow from an investigation already underway which focuses on a named person or
persons. ·Fishing expeditions· in which the subjects are generically identified, such as ·program
beneficiaries· are not covered. (ii) The match must be for the purpose of gathering evidence
against the named individual or individuals. (4) Performed for tax information-related purposes.
(5) Performed for routine administrative purposes using records relating to Federal personnel. (i)
The records to be used in the match must predominantly relate to Federal personnel (i.e., the
percentage of records in the system of records that are about Federal personnel must be greater than
of any other category). (ii) The purpose of the match must not be for purposes of taking any
adverse financial, personnel, disciplinary, or other unfavorable action against an individual. (6)
Performed using only records from systems of records maintained by an agency. (i) The purpose of
the match must not be for purposes of taking any adverse financial, personnel, disciplinary, or
other unfavorable action against an individual. (ii) A match of DoD personnel using records in a
system of records for purposes of identifying fraud, waste, and abuse is not covered. (7) Performed
to produce background checks for security clearances of Federal or contractor personnel or performed
for foreign counter-intelligence purposes. §-310.52 Computer matching publication and review
requirements. (a) DoD Components shall identify the systems of records that will be used in the

match to ensure the publication requirements of subpart G have been satisfied. If the match will require disclosure of records outside the Department of Defense, Components shall ensure a routine use has been established, and that the publication (printed page 18782) and review requirements have been met, before any disclosures are made (see subpart G of this part). (b) If a computer matching program is contemplated, the DoD Component shall contact the DPO and provide information regarding the contemplated match. The DoD DPO shall ensure that any proposed computer matching program satisfies the requirements of the Privacy Act (5 U.S.C. 552a) and OMB Matching Guidelines (54 FR 25818 (June 19, 1989)).

Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. (A) From subsections (c)(3) and (d) when access to accounting disclosure and access to or amendment of records would cause the identity of a confidential source to be revealed. Disclosure of the source's identity not only will result in the Department breaching the promise of confidentiality made to the source but it will impair the Department's future ability to compile investigatory material for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, Federal contracts, or access to classified information. Unless sources can be assured that a promise of confidentiality will be honored, they will be less likely to provide information considered essential to the Department in making the required determinations. (B) From subsection (e)(1) because in the collection of information for investigatory purposes, it is not always possible to determine the relevance and necessity of particular information in the early stages of the investigation. It is only after the information is evaluated in light of other information that its relevance and necessity becomes clear. Such information permits more informed decision-making by the Department when making required suitability, eligibility, and qualification determinations. Dated: February 28, 2019. Shelly E. Finke, Alternate OSD Federal Register Liaison Officer, Department of Defense. [FR Doc. 2019-03971 Filed 4-10-19; 8:45 am] BILLING CODE 5001-06-P

No edits were made to reference CCAs in § 170.7, which covers responsibilities for only the DIBCAC, and not CCAs. § 170.11 covers responsibilities for CCAs. DoD declined to add verbiage to address the potential revision or cancellation of an ISO/IEC standard because § 170.8 adequately reflects that the Accreditation Body shall achieve full compliance with revised ISO/IEC 17011:2017(E) standards. Standards are not effective until published as final. The DoD declined to adopt one commenter's suggestion to submit all appeals investigation materials with the final decision into eMASS, however, an updated assessment result, if any, will be input into eMASS. In addition, C3PAOs are required to retain assessment artifacts for 6 years. DoD did not agree with one commenter's assertion that the preamble description of the CMMC Program is incomplete or inaccurate, or that the rule makes implicit changes to DFARS clause 252.204-7010 reporting requirements for activities subject to the U.S.-International Atomic Energy Agency Additional Protocol. The referenced paragraph, which appears both in the preamble background section and in an overview paragraph of the supplemental documents, accurately portrays the CMMC Program as a compliance assessment model to assist in DoD's enforcement of FCI and CUI safeguarding requirements. No change has been made in either location. The DoD also declines to specify in the rule the DoD offices that review Tier 3 background investigations or equivalency determinations. No language related to Cloud Service Offerings (CSO) was added in § 170.19 column two. Assets that process, store, or transmit CUI are handled the same way regardless of whether they are from a CSO or otherwise. Therefore, there is no need to call out CSOs in the table. The DoD minimized use of the passive voice to an extent in this final rule; however, in some places the passive voice is used to emphasize the action occurring rather than the individual or entity performing the action. There is no version number in the title of the CMMC Program. Terms such as versions 1.0 or 2.0 have previously been used in DoD's public engagements as a colloquial way to communicate differences in content as the program has evolved. This final rule codifies the program and does include changes from the proposed rule. Only those public comments received during the 60-day comment period following the December 26, 2023 publication (88 FR 89058) are addressed in this final rule. 34. Error Corrections Comment: Numerous administrative comments were received that addressed formatting grammar, punctuation, and typographical errors as well as word usage and acronym errors: Wording discrepancies, redundancies, and inaccuracies were also reported by multiple comments.

1007] and employers with 0-1 employees are unlikely to sponsor a group health plan. Accordingly, the Department believes that this proposed rule, if adopted, would be unlikely to affect a substantial (printed page 1008) number of small entities that meet the RFA threshold. Thus, this analysis concludes, and the Secretary proposes to certify, that the NPRM would not result in a

significant economic effect on a substantial number of small entities. HIPAA requires the Department to consider the needs and capabilities of small and rural health care providers. [1008] As we explained in our 2003 analysis of the effect of the Security Rule on small and rural health care providers, the scalability provisions preclude the need to precisely define those categories. [1009] We have long considered the effect of our rules on small businesses in the Small Entity Analysis discussed above. However, because of the breadth of changes proposed in this NPRM, the Department has considered more closely how it would affect rural health care providers. There are approximately 2,000 rural hospitals, [1010] comprising nearly 30 percent of all hospitals [= 2,057/7,465], [1011] and the Department estimates approximately 7 to 8 percent of all health care providers operate in rural areas (counties or micropolitan areas with fewer than 50,000 inhabitants). See Regulated Entities Affected in Section V.A.2. Baseline Conditions, above. Because rural health care providers are more likely to be small businesses, they would be affected in a manner similar to small entities, as demonstrated in the Small Entity Analysis above. Likewise, to the extent that Tribal health care providers are in rural areas, which many are, [1012] our analysis of the effects on rural health care providers generally also applies. However, Tribal health providers have the benefit of access to centralized supportive services for health IT and EHR adoption, which other rural providers may lack. [1013] A primary barrier to both adoption of health information technology (health IT) and deployment of cybersecurity safeguards in rural communities is limited access to high-speed internet. Rural health care providers, such as hospitals, have adopted EHRs at a lower rate than non-rural hospitals, [1014] and thus may also have fewer electronic information systems that are subject to the Security Rule requirements, which could ease some burdens of compliance. However, as EHR adoption has increased in rural hospitals, [1015] so too have the risks of cybersecurity attacks. [1016]

4. Trust relationships - Trust relationships between systems and organizations need to be evaluated, established, and maintained based on the risk presented to the interfacing systems, the functions they support, and the grid as a whole; accounting for potential impact as the data may subsequently be directly or indirectly passed "deeper" into more protected levels. The potential impact is the basis for deciding on the wisdom of the connection, the security services selected, and the audit of attached system security services and related management processes. Roles and responsibilities need to be defined for the trusted partners, for example who will patch updates and on what schedule, who has system privileges, or who will purchase components from which suppliers. 1. Ensures external suppliers and contractors that have an impact on the security of smart grid information systems must meet the organization's policy and procedures; and 2. Establishes procedures to remove external supplier and contractor access to smart grid

on NIST standards and guidelines; and - Continued the development of a preliminary draft of SP 800-18 Revision 2, Guide for Developing Security Plans for Federal Information Systems and Organizations. - Finalize SP 800-53A Revision 4, Assessing Security and Privacy Controls in Federal Information Systems and Organizations; - Publish an errata update to SP 800-53 Revision 4; - Begin the automation of the SP 800-53 revision and public comment process in support of more timely updates to counter threats and keep up with technological advancements; - Finalize SP 800-16, A Role-Based Model for Federal Information Technology / CyberSecurity Training; - Finalize SP 800-160, Systems Security Engineering: An Integrated Approach to Building Trustworthy Resilient Systems; - Publish the IPD of SP 800-171, Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations; - Begin the development of SP 800-60 Revision 2, Guide for Mapping Types of Information and Information Systems to Security Categories; - Finalize SP 800-18 Revision 2, Guide for Developing Security Plans for Federal Information Systems and Organizations; - Expand cybersecurity outreach to include additional state, local, and tribal governments, as well as private sector organizations and academic institutions; and - Continue to support federal agencies in the effective implementation of the NIST RMF.

DoD contractors impacted is 80,000. DoD estimates that approximately 1% of the newly eligible population (800 defense contractors) will elect to join the program each year with program growth plateauing at approximately 10% of the population by Year 9. Each year, approximately 10% of participating companies will report changes to company contacts. If 10% of the pre-existing companies (2,580 in year 2) submit updates to the POC information and 800 new companies join, by year 3 this would result in 1,058 annual updates. Projected Responses per Participant: Initial collection is one per company with updates on a case-by-case basis. Annual Total Responses: 1,058. Average Burden per Response: 20 minutes. Annual Total Burden Hours: 353 hours for all

participants. Needs and Uses: Defense contractors complete a program application and sign the DIB CS Program Framework to initiate participation. The Government will collect business POC information from all DIB CS Program participants on a one-time basis, with updates as necessary, to facilitate communications and the sharing of share unclassified and classified cyber threat information. Affected Public: Business or other for-profit and not-for-profit institutions. Frequency: On occasion. Respondent's Obligation: Voluntary. F. Executive Order 13132 , ·Federalism· Executive Order 13132 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct requirement costs on State and local governments, preempts State law, or otherwise has federalism implications. This proposed rule will not have a substantial effect on State and local governments. G. Executive Order 13175 , ·Consultation and Coordination With Indian Tribal Governments· Executive Order 13175 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct compliance costs on one or more Indian tribes, preempts tribal law, or effects the distribution of power and responsibilities between the Federal Government and Indian tribes. This proposed rule will not have a substantial effect on Indian tribal governments. List of Subjects in 32 CFR Part 236 Government contracts Security measures Accordingly, DoD proposes to amend 32 CFR part 236 as follows: PART 236-DEPARTMENT OF DEFENSE (DoD) DEFENSE INDUSTRIAL BASE (DIB) CYBERSECURITY (CS) ACTIVITIES 1. The authority citation for 32 CFR part 236 continues to read as follows: Authority: 10 U.S.C. 391 , 393 , and 2224 ; 44 U.S.C. 3506 and 3544 ; 50 U.S.C. 3330 . 2. Revise the heading of 32 CFR part 236 to read as set forth above. §-236.1 [Amended] 3. Amend §-236.1 by: a. Removing ·eligible DIB participants· and adding in its place ·eligible DoD contractors·. b. Removing ·DIB CS program· and adding in its place ·DIB CS Program· wherever it appears. c. Removing ·DIB CS participants· and adding in its place ·DIB CS Program participants·. d.

(A) From subsection (d) because access to the records contained in this system would inform the subject of an investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection, and would present a serious impediment to law enforcement. In addition, granting individuals access to information collected while an Equal Opportunity and Treatment clarification/investigation is in progress conflicts with the just, thorough, and timely completion of the complaint, and could possibly enable individuals to interfere, obstruct, or mislead those clarifying/investigating the complaint. (B) From subsection (e)(4)(H) because this system of records is exempt from individual access pursuant to subsection (k) of the Privacy Act of 1974. (C) From subsection (f) because this system of records has been exempted from the access provisions of subsection (d). (18) System identifier and name. F051 AF JA I, Commander Directed Inquiries. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information except to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (f)(18)(i). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Any portion of this system of records which falls within the provisions of 5 U.S.C. 552a(k)(2) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. (A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence.

To maintain the candor and integrity of comments needed to evaluate an Air Force Academy cadet for commissioning in the Air Force. (4) System identifier and name. F036 AETC I, Cadet Records. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(5) (Detachment

Professional Officer Course Selection Rating Sheets; Air Force Reserve Officer Training Corps Form 0-24-Disenrollment Review; Memoranda for Record and Staff Papers with Staff Advice, Opinions, or Suggestions) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(4)(G) and (H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5). (iii) Reasons. To protect the identity of a confidential source who furnishes information necessary to make determinations about the qualifications, eligibility, and suitability of cadets for graduation and commissioning in the Air Force. (5) System identifier and name. F044 AF SG Q, Family Advocacy Program Records. (i) Exemption. (A) Investigative material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (f)(5)(i)(A). When claimed, this exemption allows limited (printed page 14740) protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) Investigative material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and (k)(5) from the following subsections of 5 U.S.C. 552a(c)(3) and (d). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5). (iii) Reasons.

means Government data or a Federal information system that is designated as a high value asset pursuant to OMB Memorandum M-19-03, Strengthening the Cybersecurity of Federal Agencies by enhancing the High Value Asset Program. Information means any communication or representation of knowledge, such as facts, data, or opinions, in any medium or form, including textual, numerical, graphic, cartographic, narrative, electronic, or audiovisual forms (see Office of Management and Budget (OMB) Circular No. A-130, Managing Information as a Strategic Resource). Information and communications technology (ICT) means information technology and other equipment, systems, technologies, or processes, for which the principal function is the creation, manipulation, storage, display, receipt, or transmission of electronic data and information, as well as any associated content. Examples of ICT include but are not limited to the following: computers and peripheral equipment; information kiosks and transaction machines; telecommunications equipment; telecommunications services; customer premises equipment; multifunction office machines; computer software; applications; websites; electronic media; electronic documents; Internet of Things (IoT) devices; and operational technology. Information system means a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information (44 U.S.C. 3502(8)). Information resources, as used in this definition, includes any ICT. Information technology means any equipment, or interconnected system(s) or subsystem(s) of equipment, that is used in the automatic acquisition, storage, analysis, evaluation, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information by the agency. (1) For purposes of this definition, equipment is used by an agency if the equipment is used by the agency directly or is used by a contractor under a contract with the agency that requires- (i) Its use; or (ii) To a significant extent, its use in the performance of a service or the furnishing of a product. (2) The term information technology includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources. (3) The term information technology does not include any equipment that- (i) Is acquired by a contractor incidental to a contract; or (ii) Is operational technology. Internet of Things (IoT) devices means, consistent with section 2 paragraph 4 of Public Law 116-207, devices that- (printed page 68420)

rather, it is a tool used to monitor and audit enterprise and inter-enterprise activity. Communications between the actors and this overarching director occur on a management channel that is separate from the data networks in each of the enterprises. Using a separate backchannel ensures that the tool being used to monitor and verify the various ZTA architectures does not itself impact those architectures. Enabling the overarching MSV director to control the actor VMs via a backchannel requires each of the actor VMs to have two network interface cards (NICs), one for

enterprise data and one for MSV tool interoperation. The use of a separate backchannel ensures that enterprise ZTA policies and firewalls don't need to be modified to accommodate the overarching MSV testing by permitting traffic between the overarching director and the actors that would not normally be expected to transit any of the enterprise networks.

Internet of Things; IoT products; manufacturing; risk assessment; product lifecycle; securable products; security requirements; software development; threat modelling . | 1. | There is broad support for expanding the discussion of IoT products in NIST IR 8259 to make products more central to the IoT cybersecurity baseline and allow further exploration of the cybersecurity considerations of other IoT product components beyond the device. | |-----|-----|

-----| | 2 | Many cybersecurity challenges are aggravated by the limited visibility each role in the IoT ecosystem (e.g., manufacturer, integrator, customer) has into the cybersecurity of the whole system . | | 3 | Performing risk analysis for IoT products remains a challenge due to the potential for unintended use or unexpected environments of use. | | 4 | In understanding the magnitude of a risk, it is important to understand the scale of the potential impact from a threat. | | 5 | Communicating effectively throughout IoT pre-market and post-market activities involves bridging gaps between manufacturer knowledge and customer ability to use the information. | | 6 | Transparency and traceability are foundational to maintaining product cybersecurity throughout the IoT product lifecycle. | | 7 | Discussions throughout the workshop highlighted challenges in IoT product lifecycle management emphasizing IoT product risks, vulnerabilities, and evolving ecosystem demands. |

3.2.4 Identify Potential Integrators or Suppliers and/or Perform Market Analysis Once the requirements are defined, the acquirer mission/business owner should initiate a market review for potential suppliers.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 236 [Docket ID: DOD-2019-OS-0112] RIN 0790-AK86 AGENCY: Office of the DoD Chief Information Officer, Department of Defense (DoD). ACTION: Proposed rule. SUMMARY: The DoD is proposing revisions to the eligibility criteria for the voluntary Defense Industrial Base (DIB) Cybersecurity (CS) Program. These revisions will allow a broader community of defense contractors to benefit from bilateral information sharing as when this proposed rule is finalized all defense contractors who are subject to mandatory cyber incident reporting will be able to participate. DoD is also proposing changes to definitions and some technical corrections for readability. DATES: Comments must be received by June 20, 2023. ADDRESSES: Please submit comments on this proposed rule, identified by 32 CFR part 236 , Docket ID: DOD-2019-OS-0112 and/or by Regulatory Information Number (RIN) 0790-AK86, by any of the following methods: Federal Rulemaking Portal: <https://www.regulations.gov> . Follow the instructions for submitting comments. Mail: Department of Defense, Office of the Assistant to the Secretary of Defense for Privacy, Civil Liberties, and Transparency, Regulatory Directorate, 4800 Mark Center Drive, Mailbox #24, Suite 08D09, Alexandria, VA 22350-1700. Instructions: The general policy for comments is to make these submissions available for public viewing as they are received without change, including any personal identifiers or contact information provided by the commenter. FOR FURTHER INFORMATION CONTACT: Stacy Bostjanick, Chief Defense Industrial Base Cybersecurity, Office: 703-604-3167. DIB CS Program Management Office: OSD.DIBCSIA@mail.mil . Instructions: DO NOT submit comments to this email address. SUPPLEMENTARY INFORMATION: Background and Authority

(D) From subsections (e)(4)(G), (e)(4)(H), and (e)(4)(I) (Agency Requirements) and (f) (Agency Rules), because portions of this system are exempt from the individual access provisions of subsection (d) for the reasons noted above, and therefore NGA is not required to establish requirements, rules, or procedures with respect to such access. Providing notice to individuals with respect to existence of records pertaining to them in the system of records or otherwise setting up procedures pursuant to which individuals may access and view records pertaining to themselves in the system would undermine investigative efforts and reveal the identities of witnesses, and potential

witnesses, and confidential informants. §-310.25 National Guard Bureau (NGB) exemptions. (a) General information. There are two types of exemptions, general and specific. The general exemption authorizes the exemption of a SOR from all but a few requirements of 5 U.S.C. 552a . The specific exemption authorizes exemption of a SOR or portion thereof, from only a few specific requirements. If a new SOR originates for which an exemption is proposed, or an additional or new exemption for an existing SOR is proposed, the exemption shall be submitted with the SORN. No exemption of a SOR shall be considered automatic for all records in the system. The System Manager shall review each requested records and apply the exemptions only when this will serve significant and legitimate purpose of the Federal Government. (b) Exemption for classified material. All SOR maintained by the NGB shall be exempt under section (k)(1) of 5 U.S.C. 552a to the extent that the systems contain any information properly classified under Executive Order 13526 and that is required by that Executive Order to be kept secret in the interest of national defense or foreign policy. This exemption is applicable to parts of all systems of records including those not otherwise specifically designated for exemptions herein which contain isolated items of properly classified information. (c) Exemption for anticipation of a civil action or proceeding. All systems of records maintained by the NGB shall be exempt under section (d)(5) of 5 U.S.C. 552a , to the extent that the record is compiled in reasonable anticipation of a civil action or proceeding. (d) General exemptions. No SOR within the NGB shall be considered exempt under subsection (j) or (k) of 5 U.S.C. 552a until the exemption rule for the SOR has been published as a final rule in the FR. (e) Specific exemptions. (1) System identifier and name. INGB 001, Freedom of Information Act (5 U.S.C.) and Privacy Act (5 U.S.C. 552a) Case Files. (i) Exemption. During the course of a 5 U.S.C. 552 or 5 U.S.C. 552a action, exempt materials from other systems of records may, in turn, become part of the case records in this system. To the extent that copies of exempt records from those other systems of records are entered into this 5 U.S.C. 552 or 5 U.S.C. 552a

From the NIST SP 800-172 Rev 3 Final Public Draft: Statements used to provide additional explanatory information for security controls or security control enhancements. disinformation The process of providing deliberately deceptive information to adversaries to mislead or confuse them regarding the security posture of the system or organization or the state of cyber preparedness. dual authorization The system of storage and handling designed to prohibit individual access to certain resources by requiring the presence and actions of at least two authorized persons, each capable of detecting incorrect or unauthorized security procedures with respect to the task being performed. [16, adapted] enhanced security requirements Security requirements that can be implemented in addition to the requirements in NIST Special Publication 800

Concealment and misdirection techniques may provide additional time to perform NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 core mission and business functions. The implementation of concealment and 1808

You add the domain to your list of blocked domains to prevent connections in the future. SI.L2-3.14.7 · Identify Unauthorized Use CMMC Assessment Guide · Level 2 | Version 2.13 263 Potential Assessment Considerations · Is authorized use of systems defined (e.g., data types permitted for storage or processing, personnel authorized to access, times or days of permitted use, permitted software) [a]? · Is unauthorized use of systems defined (e.g., not authorized to use systems for bitcoin mining, not authorized for pornographic content, not authorized to access gambling games/content) [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.14.7

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 DISCUSSION 1167 Identity providers (both internal and external to the organization) manage user, 1168

A person or persons outside of the Government providing commercial or financial information or trade secrets to the Government. Submitter notice. The process required by E.O. 12600 whereby when a Component receives a FOIA request for confidential commercial information, it asks the submitter of the information to advise the Component as to the information it considers exempt from release. §-286.3 Public access to DoD information. (a) The public has a right to information concerning the activities of its Government. DoD policy (32 CFR part 285) is to conduct DoD activities in an open manner and to provide the public a maximum of accurate and timely information concerning DoD activities, consistent with the need for security, public and private interests of the American people, and adherence to other requirements of law and regulation. A record requested by a member of

the public who follows rules established by proper authority in the Department of Defense shall not be withheld in whole or in part unless the record is exempt from mandatory, partial or total disclosure under the FOIA. The existence of a sound legal basis to withhold information does not preclude the DoD Component from making a discretionary release if release of that information would serve the public interest. Records requested through public affairs channels by news media representatives that would not be withheld if requested under the FOIA should be released promptly upon request. Similarly, requests from other members of the public for information that would not be withheld under the FOIA should continue to be honored through appropriate means without requiring the requester to invoke the FOIA. (b) The DoD FOIA Program Components shall prepare, in addition to normal FOIA regulations, a guide, or handbook for the use of the public in obtaining information from their Components as required by 5 U.S.C. 552(g) and section 2(b)(v) of E.O. 13392. This guide should be a short, simple explanation of what the FOIA is designed to do and how the public can use it to access Government records. Within OSD, DFOIPO is responsible for preparing this guide. Each guide shall be available on paper and electronically and shall include: (1) An index of all major information systems and a description of major information and record locator systems. (2) The types and categories of records that can be obtained through FOIA requests. (3) A concise description of the FOIA exemptions and how the Component determines whether the record can be released. (4) An explanation of how to make a FOIA request, how long the requester can expect to wait for a reply, and the right of appeal. (5) The location of the FOIA reading rooms(s) within the Component. (6) The location of the Component's Web site. (7) A reference to the Component's FOIA regulation and how to obtain a copy. § 286.4 Procedures. (a) Compliance with the FOIA. DoD personnel shall comply with the FOIA, this part, and DoD FOIA policy (32 CFR part 285

IR.L2-3.6.3 · Incident Response Testing CMMC Assessment Guide · Level 2 | Version 2.13 143 who is responsible for incident management; what tasks are assigned within the IT organization; what support is needed from legal, public affairs, or other business components; how resources are added if needed during the incident ; and how law enforcement is involved. Any negative impacts to the normal day -to-day operations when responding to an incident should also be identified and documented. Example You decide to conduct an incident response table top exercise that simulates an attacker gaining access to the network through a compromised server. You include relevant IT staff such as security, database, network, and system administrators as participants. You also request representatives from legal, human resources, and communications. You provide a scenario to the group and have prepared key questions aligned with the response plans to guide the exercise. During the exercise, you focus on how the team executes the incident response plan. Afterward, you conduct a debrief with everyone that was involved to provide feedback and develop improvements to the incident response plan [a]. Potential Assessment Considerations · Does the incident response policy outline requirements for regular incident response plan testing and reviews of incident response capabilities [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.6.3

The term CMMC Accreditation Body is a generic term for whichever accreditation body is supporting the DoD at a given time. The rule has been updated to remove reference to any specific accreditation body. There is only one Accreditation Body for the DoD CMMC Program at any given time, and its primary mission is to authorize and accredit the C3PAOs. The Accreditation Body does not issue certifications. The current CMMC AB is under a no-cost contract that has followed normal DoD contracting procedures. The DoD declines to delete the section outlining requirements for the CMMC AB, which are enduring and apply irrespective of which entity the DoD has currently approved to serve in that capacity. This rule identifies the requirements for the Accreditation Body's role in the CMMC Ecosystem. The DoD has a variety of options available to address the commenter's concern should the current CMMC AB not be able to fulfill this role. These include but are not limited to, contracting with a new/replacement Accreditation Body. And authorized and accredited C3PAOs would be able to continue conducting CMMC assessments. § 170.8(b)(6) requires the CMMC AB to complete a CMMC Level 2 assessment conducted by DCMA DIBCAC that must meet all CMMC Final Level 2 certification assessment requirements and will not result in a CMMC Level 2 certification. This requirement for an assessment is based on the potential compilation of sensitive information on the CMMC AB's information systems. After the CMMC AB's successful completion of this Level 2 assessment, the DoD reserves the right to send CUI to the CMMC AB, as appropriate. Requirements for the CMMC AB, detailed in § 170.8(b) of this rule, include DoD requirements to comply with Conflict of Interest, Code of Professional Conduct and Ethics policies as set forth in the DoD contract with the AB. § 170.8(b)(3) details the ISO/IEC requirements the CMMC AB must meet and the timeline for meeting them. § 170.8(b)(3)(i) and (ii) further detail the requirements for the CMMC AB to authorize and

accredit C3PAOs. The CMMC AB is under contract with the DoD and must fully comply with the contract requirements. The CMMC rule was updated to clarify that the CMMC AB must be a U.S.-based signatory to the International Laboratory Accreditation Cooperation Mutual Recognition Arrangement within 24 months of DoD approval and must operate in accordance with ISO/IEC 17011:2017(E). The rule was also updated to clarify that a disqualifying eligibility determination may result in the CMMC AB losing its authorization or accreditation under the CMMC Program.

303. ·Recovering from a Cybersecurity Attack and Protecting the Future in Small, Rural Health Organizations,· *supra* note 295. Back to Citation 304. *Id.* Back to Citation 305. *Id.* Back to Citation 306. See, e.g., ·Fact Sheet: Biden-Harris Administration Bolsters Protections for Americans' Access to Healthcare Through Strengthening Cybersecurity,· The White House (June 10, 2024), <https://www.whitehouse.gov/briefing-room/statements-releases/2024/06/10/fact-sheet-biden-harris-administration-bolsters-protections-for-americans-access-to-healthcare-through-strengthening-cybersecurity/> ; ·How Do Ransomware Attacks Impact Rural Hospitals?,· National Institute for Health Care Management Foundation, p. 1 (2024), https://nihcm.org/assets/articles/FINAL-NIHCM-RI-Hannah-Neprash_2024-08-01-132728_ushq.pdf . Back to Citation 307. ·How Do Ransomware Attacks Impact Rural Hospitals?· *supra* note 306, p. 2. Back to Citation 308. *Id.* Back to Citation 309. *Id.* Back to Citation 310. ·Kevin Collier, ·An Illinois hospital is the first health care facility to link its closing to a ransomware attack,· NBC News (June 12, 2023), <https://www.nbcnews.com/tech/security/illinois-hospital-links-closure-ransomware-attack-rcna85983> . Back to Citation 311. *Id.* Back to Citation 312. ·Fact Sheet: Biden-Harris Administration Bolsters Protections for Americans' Access to Healthcare Through Strengthening Cybersecurity,· *supra* note 306. Back to Citation 313. See, e.g., ·Free Cybersecurity Services and Tools,· Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security, <https://www.cisa.gov/resources-tools/resources/free-cybersecurity-services-and-tools> ; ·Cyber Hygiene Services,· Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security, <https://www.cisa.gov/cyber-hygiene-services> ; ·Cybersecurity Resources for High-Risk Communities,· Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security, <https://www.cisa.gov/audiences/high-risk-communities/cybersecurity-resources-high-risk-communities> . Back to Citation 314. See, e.g., 45 CFR 164.306 . Back to Citation 315. · See sec. 261 of Pub. L. 104-191 , 110 Stat. 2021 (Aug. 21, 1996), as amended by sec. 1104(a) of Pub. L. 111-148 , 124 Stat. 146 (Mar. 23, 2010) (codified at 42 U.S.C. 1320d note). Back to Citation 316. *Id.* Back to Citation 317. 42 U.S.C. 1320d-1(c)(1) and (2) . Back to Citation 318. 42 U.S.C. 1320d-1(c)(2)(B) . Back to Citation 319. · See 42 U.S.C. 1320d(7) (definition of ·Standard·). Back to Citation 320. · See 42 U.S.C. 1320d-2(a)(1) . Back to Citation 321. 65 FR 50312 , 50320 (Aug. 17, 2000); see also 42 U.S.C. 1320d-2(b) , (c), and (d); sec. 264(c) of HIPAA. Back to Citation 322. 65 FR 50312 , 50320 (Aug. 17, 2000). Back to Citation 323. 45 CFR 160.103 (definition of ·Standard·). Back to Citation 324. 63 FR 43242 , 43249 (Aug. 12, 1998); 68 FR 8334 , 8341 (Feb. 20, 2003). Back to Citation 325. 78 FR 5566 , 5589-91 , 5693-95 (Jan. 25, 2013). Back to Citation 326. 63 FR 43249 (Aug. 12, 1998); 68 FR 8341 (Feb. 20, 2003).

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. It is expected that the guidance and applicable recommendations in this publication will be incorporated into the security plans and operational processes of federal enterprise networks. Likewise, it is expected that applicable recommendations will be incorporated into the service agreements for federal contracts for hosted application services and internet transit services. It is expected that the guidance and applicable recommendations from this publication will be incorporated into the security plans and operational processes of federal enterprise networks. Likewise, it is expected that applicable recommendations will be incorporated into the service agreements for federal contracts for hosted application services and internet transit services. ·is document also contributes to the ongoing efforts by NIST and NTIA [DOC -Botnet] [BotnetRoadmap] to respond to Presidential Executive Order 13800 [PEO-13800].

According to ISCMA_ An Information Security Continuous Monitoring Program Assessment, Executive

Summary: s. At each risk management level, an ISCMA unique to that level is conducted. Judgments are made about assessment elements, which are statements that should be true for a wellimplemented ISCM program. Under ISCMA, an assessment with the maximum breadth and depth consists of 128 assessment elements. The results for each risk management level are then merged into a single overall result. 1 ISCM is defined in NIST Special Publication (SP) 800-137 [SP800-137], Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations, as maintaining ongoing awareness of information security, vulnerabilities, and threats to support organizational risk management decisions. 2 Risk management levels are described in NIST SP 800-39 [SP800-39], Managing Information Security Risk: Organization, Mission, and Information System View . The ISCMA process proceeds according to the following steps: - Plan the approach - Conduct: Evaluate the elements - Conduct: Score the judgments - Report: Analyze the results - Report and Follow-on: Formulate actions Part of the 'Plan the Approach' step is to determine how to organize the selected participants at each risk management level. For example, all participants from Level 2 could conduct a single ISCMA as a group with judgments made by consensus. Alternatively, participants from each mission or business process could conduct individual assessments in parallel and allow [ISCMAx] to assemble and merge those assessments. In the latter case, the most common judgment of all the individual assessments is the overall judgment for a risk management level. ISCMAx produces a detailed scorecard and associated graphical output. It also automatically reports conditions that may warrant further analysis, such as: - Elements where the overall organizational judgment is weakest - Elements where different risk management levels have widely divergent judgments

3.3.7 | Endpoint Security Controls... 3.3.7 Endpoint Security Controls Some SSL VPNs provide endpoint security controls that include host integrity checking and security protection mechanisms.

by collapsing the separate paragraphs into one paragraph (c) to address both standards and implementation specifications and to remove the distinction between ·addressable· and ·required· implementation specifications. Instead, proposed paragraph (c), if adopted, would require regulated entities to comply with both the standards and implementation specifications. The Department believes that eliminating the distinction would make clear to regulated entities what has always been a requirement that the Security Rule sets a floor for cybersecurity protections and that its flexibility is in allowing them to choose the manner in which they meet the standards and implementation specifications, not whether they meet them. The proposed change also would be consistent with NCVHS' recommendation to require regulated entities to meet certain minimum cybersecurity hygiene requirements. [432] The Department acknowledges that proposing to remove the addressability distinction is a change from the approach adopted in the 2003 Final Rule. At that time, we explained that the decision to include addressable implementation specifications was made to provide additional flexibility to (printed page 934) covered entities. [433] In this rulemaking, the Department proposes to strengthen protections and address evolving cybersecurity threats. While we acknowledge that this proposal would reduce the Security Rule's flexibility, we believe that it is necessary to do so to achieve HIPAA's purpose of an efficient and effective health care system that relies on the secure electronic exchange of ePHI. Importantly, removing the distinction between required and addressable would not eliminate all of the Security Rule's flexibility and scalability. Instead, it would simply clarify for regulated entities where the floor of protection must lie, and regulated entities must implement solutions that meet that floor, taking into consideration their needs and capabilities. For example, a small or rural health care provider must implement a solution that ensures the protection of ePHI in the manner required by the Security Rule, but the specific solution that it chooses would reflect consideration of its particular circumstances, including available resources. In some cases, a small or rural health care provider might opt to implement a cloud-based EHR or other software solution that could reduce the health care provider's need to separately invest in data storage, backup systems, and IT personnel. And in other circumstances, a small or rural health care provider might choose to contract with a third party to provide IT support, rather than hiring its own workforce members to perform such functions. The Department also proposes to delete the maintenance provision at 45 CFR 164.306(e)

Building upon NISTIR 8074 Volume 2, this report describes 12 cybersecurity core areas and provides examples of relevant standards. The analysis is based on the information in Annex D, which maps cybersecurity standards that may be relevant for IoT systems to the dozen cybersecurity core areas. The annotated standards listings in Annex D are not exhaustive, but they represent an extensive effort to identify presently relevant IoT cybersecurity standards. The market impacts of existing standards are noted; possible gaps in standards are identified in Section 8. While the Annex D

listing is a onetime snapshot, it should prove useful as a point of departure for maintaining awareness of the evolving standards landscape. A summary of the status of cybersecurity standardization for the five specific examples of IoT applications is provided in Table 4. Smart manufacturing includes software and sensors that allow for precise predictions of maintenance needs, material demand, overtime, and other factors, based on data captured through all points of production. However, the volume of unstructured data (e.g., emails, blogs, webpages) that could be consumed in big-data projects creates new kinds of security challenges and requires a new mindset toward data-centric security measures. Big data is too new for security personnel to understand what constitutes normal behavior. Security professionals need to comprehend the analytics and automation being applied to determine how best to protect a big-data enterprise, because there is currently no practical way to fully maintain situational awareness of the data at the accelerated rates of acquisition and change. With that level of Combining the advantages of big data and mobile devices, augmented reality (AR) is being used with increasing frequency on the shop floor, including as a training aid, maintenance aid, and operational dashboard.

NIST Special Publication 800 NIST SP 800-172r3 fpd Enhanced Security Requirements for Protecting Controlled Unclassified Information Final Public Draft Ron Ross Victoria Pillitteri This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-172r3.fpd> NIST Special Publication 800 NIST SP 800-172r3 fpd Enhanced Security Requirements for Protecting Controlled Unclassified Information Final Public Draft Ron Ross Victoria Pillitteri Computer Security Division Information Technology Laboratory This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-172r3.fpd> September 2025 U.S. Department of Commerce Howard Lutnick, Secretary National Institute of Standards and Technology Craig Burkhardt, Acting Under Secretary of Commerce for Standards and Technology and Acting NIST Director

) to make it a prohibited act to refuse to permit access to, or copying of, any record as required by section 414 or 704(a) of the FD&C Act; or to fail to establish or maintain any record as required by section 414(b) of the FD&C Act; or to refuse to permit access to, or verification or copying of, any such required record; or for any person to use to his own advantage, or to reveal, other than to the Secretary or officers or employees of the Department of Health and Human Services, or to the courts when relevant in any judicial proceeding under the FD&C Act, any information acquired under authority of section 414 of the FD&C Act. To implement these provisions, on May 9, 2003 (68 FR 25188), FDA issued a proposed rule to require the establishment and maintenance of records to identify the immediate previous sources and immediate subsequent recipients of food. In addition to section 306 of the Bioterrorism Act, which amends the FD&C Act as described previously, FDA is relying on section 701(a) of the FD&C Act (21 U.S.C. 371(a)) in issuing this final rule. Section 701(a) authorizes the agency to issue regulations for the efficient enforcement of the FD&C Act.

II. Highlights of the Final Rule and Summary of the Significant Changes Made to the Proposed Rule

A. Highlights of this Final Rule The highlights of this final rule are described briefly in the following paragraphs, and are discussed in more detail later in the preamble of this document: Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States are subject to the regulations in part 1 (21 CFR part 1) subpart J of this final rule (i.e., recordkeeping and access requirements); The following persons or facilities are excluded from all of the regulations in subpart J of this final rule: Farms; restaurants; those performing covered activities when the food is subject to the exclusive jurisdiction of the U.S. Department of Agriculture (USDA) under the Federal Meat Inspection Act (FMIA) (21 U.S.C. 601 et seq.), the Poultry Products Inspection Act (PPIA) (21 U.S.C. 451 et seq.), or the Egg Products Inspection Act (EPIA) (21 U.S.C. 1031 et seq.); and foreign persons, except foreign persons who transport food in the United States. The following persons or facilities are excluded from the requirement to establish and maintain records in §§ 1.337 and 1.345 of subpart J of this final rule, but are subject to the record availability requirements in §§ 1.361 and 1.363 for existing records: (1) Fishing vessels not engaged in processing as defined in § 123.3(k) (21 CFR part 123.3(k)

(4) Require all CCPs, who are not eligible to obtain a Tier 3 background investigation, to meet the equivalent of a favorably adjudicated Tier 3 background investigation. DoD will determine the Tier 3 background investigation equivalence for use with the CMMC Program only. (5) Provide all documentation and records in English. (6) Not share any CMMC assessment-related outcomes or advance information with any person not assigned to that specific assessment, except as otherwise required by law. Subpart D-Key Elements of the CMMC Program § 170.14 CMMC Model. (a) Overview. The CMMC

Model incorporates the security requirements from: (1) FAR 52.204-21 (48 CFR 52.204-21) Basic Safeguarding of Covered Contractor Information Systems; (2) NIST SP 800-171 Rev 2, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations (incorporated by reference, see § 170.2); and (3) Selected requirements from NIST SP 800-172, Enhanced Security Requirements for Protecting Controlled (printed page 89128) Unclassified Information: A Supplement to NIST Special Publication 800-171 Rev 2, (incorporated by reference, see § 170.2).

(b) CMMC domains. The CMMC Model consists of domains that map to the Security Requirement Families defined in NIST SP 800-171 Rev 2. (c) CMMC level requirements. CMMC Levels 1-3 utilize the safeguarding requirements and security requirements specified in FAR clause 52.204-21 (Level 1), NIST SP 800-171 Rev 2 (Level 2), and selected security requirements from NIST SP 800-172 (Level 3). This paragraph discusses the numbering scheme and the security requirements for each level. (1) Numbering. Each security requirement has an identification number in the format-DD.L#-REQ-where: (i) DD is the two-letter domain abbreviation; (ii) L# is the CMMC level number; and (iii) REQ is the FAR clause 52.204-21 paragraph number, NIST SP 800-171 Rev 2, or NIST SP 800-172 requirement number. (2) CMMC Level 1 requirements. The security requirements in CMMC Level 1 are those set forth in FAR clause 52.204-21(b)(1)(i) through (b)(1)(xv). (3) CMMC Level 2 requirements. The security requirements in CMMC Level 2 are identical to the requirements in NIST SP 800-171 Rev 2. (4) CMMC Level 3 requirements. The security requirements in CMMC Level 3 are selected from NIST SP 800-172, and where applicable, Organization-Defined Parameters (ODPs) are assigned. Table 1 to this paragraph identifies the selected requirements and applicable ODPs that represent the CMMC Level 3 security requirements. ODPs for the NIST SP 800-172 requirements are italicized, where applicable: Table 1 to § 170.14(c)(4) Security requirement No. 1 CMMC level 3 security requirements (Selected NIST SP 800-172 Requirement with DoD ODPs italicized) (i) AC.L3-3.1.2e Restrict access to systems and system components to only those information resources that are owned, provisioned, or issued by the organization. (ii) AC.L3-3.1.3e Employ secure information transfer solutions

The food security benefits of recordkeeping come from mitigating a terrorist attack on the food supply, and preventing unnecessary expense in the event of a hoax or a small terrorist event. While we are unable to estimate the benefits from such scenarios, we can point to investigative speed as a principal mechanism for mitigating their costs. The first benefit-mitigating the effects of an attack-is similar to the food safety benefit. Investigations will be quicker because of better records. Investigation speed may be crucial in the early period after a terrorist attack to more quickly determine the likely scope and scale of the contamination. With quicker investigations, the government can act sooner to reduce the public health and other effects of a terrorist attack on the food supply. These benefits should be qualitatively the same as in the case of an accidental outbreak of food-related illness, but we expect them to be potentially larger for a terrorist attack on the food supply. The second counterterrorism benefit from recordkeeping is also difficult to quantify but may be important: the ability to identify quickly a potential food security hoax. The hoax could be completely false, or it could be a small event masquerading as a large event. For example, a terrorist could contaminate a single container of some food and send out an Internet message stating that the entire national stock of that food was contaminated. If the goal is to spread terror rather than to cause mass illness, then a small attack or even an Internet announcement with no contaminated products could persuade consumers that the risk is real. With a sufficiently plausible background story implicating a widely-consumed food, the hoax might lead to (printed page 71615) extensive protective efforts by businesses and consumers. Consumers might take costly preventive actions, such as throwing away food, stopping their consumption of the suspect food item, or visiting physicians or emergency rooms to determine if they have been exposed to some hazard. Producers and distributors might destroy inventories of the suspect food as a preventive measure. If there is widespread uncertainty about the extent of contamination, this protective behavior could easily generate high costs. If the terrorist attack on a food is a small-scale event masquerading as a national event, a full system of records will allow the agency to trace the suspect foods through the food chain to determine the extent of contamination. The government could quickly narrow down the range of suspect foods and, if the risk is absent, reassure the public that the suspect foods are indeed free of contamination by terrorists. The ability to move quickly and authoritatively will possibly generate real benefits by preventing costly defensive actions by businesses and consumers. 2. Benefits: Model Framework

(2) Rank, position, or title alone does not authorize access to personal information about others.

(b) Disclosures required by the FOIA. (1) All records must be disclosed if their release is required by FOIA (5 U.S.C. 552), as implemented by 32 CFR part 286 . The FOIA requires records

be made available to the public unless withholding is authorized pursuant to one of nine exemptions or one of three law enforcement exclusions under the Act. (i) The DoD Component must be in receipt of a FOIA request and a determination made that the records are not withholdable pursuant to a FOIA exemption or exclusion before the records may be disclosed. (ii) Records that have traditionally been released to the public by the Components may be disclosed whether or not a FOIA request has been received. (2) The standard for exempting most personal records, such as personnel, medical, and similar records, is FOIA Exemption 6 (32 CFR part 286.12(e)). Under that exemption, records can be withheld when disclosure, if other than to the individual about whom the information pertains, would result in a clearly unwarranted invasion of the individual's personal privacy. (3) The standard for exempting personal records compiled for law enforcement purposes, including personnel security investigation records, is FOIA Exemption 7(C) (32 CFR part 286.12(g)). Under that exemption, records can be withheld when disclosure, if other than to the individual about whom the information pertains, would result in an unwarranted invasion of the individual's personal privacy. (4) If records or information are exempt from disclosure pursuant to the standards set forth in paragraphs (b)(2) and/or (b)(3) of this section, and the records are contained in a system of records (See § 310.10(a) of subpart B, the Privacy Act (5 U.S.C. 552a) prohibits release. (5) Personal information that is normally releasable. (i) DoD civilian employees. (A) Some examples of personal information regarding DoD civilian employees that normally may be released without a clearly unwarranted invasion of personal privacy include: (1) Name. (2) Present and past position titles. (3) Present and past grades. (4) Present and past annual salary rates. (5) Present and past duty stations. (6) Office and duty telephone numbers. (7) Position descriptions. (B) All disclosures of personal information regarding Federal civilian employees shall be made in accordance with OPM release policies (see 5 CFR part 293.311). (ii) Military members. (A) While it is not possible to identify categorically information that must be released or withheld from military personnel records in every instance, the following items of personal information regarding military members normally may be disclosed without a clearly unwarranted invasion of their personal privacy: (1) Full name. (2) Rank. (3) Date of rank. (4) Gross salary. (5) Past duty assignments. (6) Present duty assignment. (7) Future assignments that are officially established. (8) Office or duty telephone numbers. (9) Source of commission. (10)

Information may be referred to other government agencies or to non-government agencies or to non-government personnel (including contractors or prospective contractors) having an identified interest in a particular invention and the Government's rights therein. The DoD 'Blanket Routine Uses' set forth at the beginning of DLA's compilation of systems of records notices apply to this system. Policies and practices for storing, retrieving, accessing, retaining, and disposing of records in the system: Storage: Records are maintained in paper and computerized form. Retrieval: Filed by names of inventors. Safeguards: Access is limited to those individuals who require the records for the performance of their official duties. Paper records are maintained in buildings with controlled or monitored access. During non-duty hours, records are secured in locked or guarded buildings, locked offices, or guarded cabinets. The electronic records systems (printed page 18788) employ user identification and password or smart card technology protocols. Retention and disposal: Records maintained by the HQ and field Offices of Counsel are destroyed 26 years after file is closed. Records maintained by field level Offices of Counsel where patent applications are not prepared are destroyed 7 years after closure. System manager(s) and address: Office of the General Counsel, Headquarters, Defense Logistics Agency, ATTN: DG, 8725 John J. Kingman Road, Stop 2533, Fort Belvoir, VA 22060-6221. Notification procedure: Individuals seeking to determine whether information about themselves is contained in this system should address written inquiries to the Privacy Officer, Headquarters, Defense Logistics Agency, ATTN: DSS-B, 8725 John J. Kingman Road, Stop 6220, Fort Belvoir, VA 22060-6221, or the Privacy Officers at DLA field activities. Official mailing addresses are published as an appendix to DLA's compilation of systems of records notices. Record access procedures: Individuals seeking access to information about themselves contained in this system should address written inquiries to the Privacy Officer, Headquarters, Defense Logistics Agency, ATTN: DSS-B, 8725 John J. Kingman Road, Stop 6220, Fort Belvoir, VA 22060-6221, or the Privacy Officers at the DLA field activities. Official mailing addresses are published as an appendix to DLA's compilation of systems of records notices. Individuals should provide information that contains full name, current address and telephone numbers of requester. For personal visits, each individual shall provide acceptable identification, e.g., driver's license or identification card. Contesting record procedures: The DLA rules for accessing records, contesting contents, and appealing initial agency determinations are contained in

32 CFR part 323, or may be obtained from the Privacy Act Officer, Headquarters, Defense Logistics Agency, ATTN: DSS-B, 8725 John J. Kingman Road, Stop 6220, Fort Belvoir, VA 22060-6221. Record source categories:

This document leverages the ISO/IEC standards as much as possible in forming vulnerability disclosure guidelines for the Federal Government. Federal vulnerability disclosure programs should follow, to the extent possible, the terminology used in this document to facilitate interoperability in communications (e.g., using the same names for the various actors), as well as for internal efforts of identification, assessment, and the minimization or elimination of vulnerabilities. When a needed term is not defined in this document but does exist in the ISO/IEC standards, the term from the standards should be used. A glossary of the major terms used in this document is provided in Appendix B. Each FCB member should develop the ability to receive source vulnerability reports from reporters, maintain a database of received reports, and engage in secure communications (e.g., using a report tracking system). 2 The expectation for communication with the reporter should be established, including the initial acknowledgment, status updates, and agreed-upon method of communication. The actual receipt of a source vulnerability report may take multiple forms (e.g., email, web forms, or a phone hotline) and should be stated in a public policy. It is also Prior to the receipt of any vulnerabilities, each FCB member will determine which government VDPOs fall within the scope of their services. The FCB member will then obtain and maintain a list of VDPO contacts within the relevant government agencies that receive and handle source vulnerability reports. Each FCB member should develop the capability to forward reports to VDPOs and to engage in ongoing communications to enable coordination. Lastly, FCB members may engage with industry-tied vulnerability coordination entities (e.g., CERT/CC 3) to facilitate coordination with non-government software and/or service providers.

From the NIST SP 800-172 Rev 3 Final Public Draft: Threat literacy training includes educating individuals on the various ways that APTs can infiltrate the organization (e.g., through websites, emails, pop-ups, articles, and social engineering) and describes techniques for recognizing suspicious emails, the NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 use of removable systems in non-secure settings, and the potential targeting of 772

% of establishments That Are Very Small % of Food Industry Revenue From Very Small Establishments
Manufacturers 77 15 Wholesalers 81 14 Transporters 90 16 Grocery outlets 88 18
Convenience outlets 73 18 Importers 82 14 Mixed-type facilities 82 15 Moreover, many of our failures in a typical trace back investigation (i.e., unclassified scenarios) have been at the wholesaler (distributor) level. As noted in the table A of this document, 81 percent of the wholesalers are considered very small. We also would have significant concerns if 90 percent of the transporters (as very small entities) were excluded from the requirements to establish and maintain records. In light of the previous information, FDA does not believe we would have an effective recordkeeping system if we were to exempt all very small entities from the rule. Unlike the very small retailers who are at the end of the distribution chain only, a full exemption by size would create holes throughout the distribution chain and would not provide FDA adequate assurances that, in the event of a threat of serious adverse health consequences or death, FDA would be able to conduct an efficient and effective tracing investigation. However, individual direct sellers as described in the comment who qualify as retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements of subpart J in this final rule, except the record access provisions for existing records under §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) In addition, FDA has considered the size of a business in establishing compliance dates for this final rule. Further, the final rule exempts direct sellers who are otherwise subject to the recordkeeping requirements of this rule and who sell food products directly to consumers from keeping records of the immediate subsequent recipients of that food. (Comment 52) Several comments state FDA should interpret the exemption from maintaining records for immediate subsequent recipients of food to expressly include retail farm supply and feed stores that sell finished product directly to consumers and final purchasers. For instance, the comments note that many small rural feed manufacturers also have a retail outlet in their facilities that sell bagged feed, pet food, and feed ingredients/additives over-the-counter directly to consumers and to final purchasers for their own animals. These products are not resold by the purchaser-customer. Maintaining records of these sales is not common practice today, would represent a costly burden to such enterprises,

many of which are small businesses, and would not demonstrably enhance human or animal protection from bioterrorism-related threats.

3.1.10 Logging and Auditing Vulnerability (CWE-778 and CWE-779) Description Logging and auditing are common system and security functions aiding in system management, event identification, and event reconstruction.

(a) The need for customary progress payments in accordance with subpart 32.5 of the Federal Acquisition Regulation (FAR) or performance-based payments in accordance with FAR subpart 32.10 will not be considered as a handicap or adverse factor in the award of the contract. (b) This solicitation includes a FAR and Defense Federal Acquisition Regulation Supplement (DFARS) clause for performance-based payments and a FAR clause for progress payments. The resultant contract will include either performance-based payments or progress payments, not both, except as may be authorized on separate orders subject to FAR 32.1003(c). (1) The performance-based payments clauses will be included in the contract if: (i) The Offeror has provided positive representation in response to DFARS 252.232-7015, Performance-Based Payments-Representation; (ii) The Offeror proposes a performance-based payment arrangement in accordance with FAR 52.232-28, Invitation to Propose Performance-Based Payments, including proposed events and timing, event completion criteria, event values, and expected expenditure profile; and (iii) The Offeror and the Government reach agreement on all aspects of the arrangement. (2) If performance-based payments clauses are not included in the resultant contract, the progress payments clause included in this solicitation will be included in any resultant contract, modified or altered if necessary in accordance with FAR 52.232-16 and its Alternate I. Even though the progress payments clause is included in the contract, the clause shall be inoperative during any time the contractor's accounting system and controls are determined by the Government to be inadequate for segregation and accumulation of contract costs. (End of provision) [FR Doc. 2020-06728 Filed 4-7-20; 8:45 am] BILLING CODE 5001-06-P

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 · Implementing dual authorization controls for critical or sensitive operations 337

Establish and deploy technical controls for securing the covered entity's or business associate's relevant electronic information systems and technology assets in its relevant electronic information systems, including workstations, in a consistent manner, and maintain such electronic information systems and technology assets according to the covered entity's or business associate's established secure baselines. (2) Implementation specifications ·(i) Anti-malware protection. Deploy technology assets and/or technical controls that protect all of the covered entity's or business associate's technology assets in its relevant electronic information systems against malicious software, including but not limited to viruses and ransomware. (ii) Software removal. Remove extraneous software from the covered entity's or business associate's relevant electronic information systems. (iii) Configuration. Configure and secure operating system(s) and software consistent with the covered entity's or business associate's risk analysis under § 164.308(a)(2). (iv) Network ports. Disable network ports in accordance with the covered entity's or business associate's risk analysis under § 164.308(a)(2). (v) Maintenance. Review and test the effectiveness of the technical controls required by this paragraph (c) at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. (d) Standard: Audit trail and system log controls ·(1) General. Deploy technology assets and/or technical controls that record and identify activity in the covered entity's or business associate's relevant electronic information systems. (2) Implementation specifications ·(i) Monitor and identify. The covered entity or business associate must deploy technology assets and/or technical controls that monitor in real-time all activity in its relevant electronic information systems, identify indications of unauthorized persons or unauthorized activity as determined by the covered entity's or business associate's risk analysis under § 164.308(a)(2), and alert workforce members of such indications in accordance with the policies and procedures required by § 164.308(a)(7). (ii) Record. The covered entity or business associate must deploy technology assets and/or technical controls that record in real-time all activity in its relevant electronic information systems. (iii) Retain. The covered entity or business associate must deploy technology assets and/or technical controls to retain records of all activity in its relevant electronic information systems as determined by the covered entity's or business associate's policies and procedures for information system activity review at

§ 164.308(a)(7)(ii)(A). (iv) Scope. Activity includes creating, accessing, receiving, transmitting, modifying, copying, or deleting any of the following: (A) Electronic protected health information. (B) Relevant electronic information systems and the information therein. (v)

3.2.4 | Web Server and Network Administrators ... 3.2.4 Web Server and Network Administrators Web server administrators are system architects responsible for the overall design, implementation, and maintenance of a Web server.

Back to Citation 940. · View ICR, · Office of Information and Regulatory Affairs, Office of Management and Budget (July 9, 2024), https://www.reginfo.gov/public/do/PRAViewICR?ref_nbr=202401-0945-002 . Back to Citation 941. 63 FR 43242 (Aug. 12, 1998). Back to Citation 942. 68 FR 8334 (Feb. 20, 2003). Back to Citation 943. 78 FR 5566 (Jan. 25, 2013). Back to Citation 944. · See · Occupational employment and wages· May 2023, · U.S. Department of Labor, Bureau of Labor Statistics, Table 1. National employment and wage data from the Occupational Employment and Wage Statistics survey by occupation (Apr. 3, 2024), <https://www.bls.gov/news.release/pdf/ocwage.pdf> . Back to Citation 945. · This includes 60 days from publication of a final rule to the effective date and an additional 180 days until the compliance date. Back to Citation 946. · A firm may be an umbrella organization that encompasses multiple establishments. Back to Citation 947. · 2021 [Statistics of U.S. Businesses] SUSB Annual Data Tables by Establishment Industry, · United States Census Bureau, U.S. & States, 6-digit NAICS (Dec. 2023), <https://www.census.gov/data/tables/2021/econ/susb/2021-susb-annual.html> . Back to Citation 948. · This percentage was rounded. Back to Citation 949. · See · 2023 NCPA Digest, sponsored by Cardinal Health, · National Community Pharmacists Association, Table 5, p. 9 (2023), <https://www.cardinalhealth.com/content/dam/corp/web/documents/Report/cardinal-health-2023-ncpa-digest.pdf> ; see also · 2021 [Statistics of U.S. Businesses] SUSB Annual Data Tables by Establishment Industry, · supra note 947. Back to Citation 950. · See Scott Pace, · The Role and Value of Pharmacy Services Administrative Organizations (PSAOs), · Impact Management Group, p. 3 (July 20, 2022), https://content.naic.org/sites/default/files/call_materials/The%20Role%20and%20Value%20of%20Pharmacy%20Services%20Administrative%20July%202022.pdf ; see also · The Role of Pharmacy Services Administrative Organizations for Independent Retail and Small Chain Pharmacies, · Avalere Health, p. 4 (Sept. 30, 2021), https://documents.ncsl.org/wwwncsl/Foundation/sponsor-views/The_Role_of_PSAOs_Independent_Pharmacies.pdf. Back to Citation 951. See · Provider of Services File· Internet Quality Improvement and Evaluation System· Home Health Agency, Ambulatory Surgical Center, and Hospice Providers, · Centers for Medicare & Medicaid Services (2024), <https://data.cms.gov/provider-characteristics/hospitals-and-other-facilities/provider-of-services-file-internet-quality-improvement-and-evaluation-system-home-health-agency-ambulatory-surgical-center-and-hospice-providers> ; · Provider of Services File· Hospital & Non-Hospital Facilities, · Centers for Medicare & Medicaid Services (2024), <https://data.cms.gov/provider-characteristics/hospitals-and-other-facilities/provider-of-services-file-hospital-non-hospital-facilities> . Back to Citation

- Prohibit DISA access from being activated except for test purposes. - Use the following precautions when the DISA is activated for testing purposes: - Activate the feature only for the duration of the test. - Make the access code at least eight (8) characters long. - Change the access code at the conclusion of the test session. - Deactivate the feature at the conclusion of the test. When a user dials 9 to place an outside call, the call is routed over a randomly selected trunk. Dial Access Codes (DACs) are used to allow access to a specific trunk, such as a WATS (Wide Area Telecommunication Services) trunk. DACs should not be provided to the user except for paging trunks. Trunk group DACs shall be no less than 3 digits in length. DACs should be disabled except for testing purposes. - Access to user trunks should be through ARS only. - Use the following precautions if DACs are activated for testing purposes: - Activate the feature only for the duration of the test. - Make the code a three digit number. - Change the code at the conclusion of the test session. - Deactivate the feature at the conclusion of the test.

Andrew Witty, UnitedHealth Group Chief Executive Officer, in his testimony to Congress, estimated that the breach of Change Healthcare may involve the PHI of one-third of Americans. · Hacking America's Health Care: Assessing the Change Healthcare Cyber Attack and What's Next, · Subcommittee on Oversight and Investigations of the Committee on Energy and Commerce, Hearing Before the Committee on Finance (May 1, 2024), <https://www.finance.senate.gov/hearings/hacking-americas->

health-care-assessing-the-change-healthcare-cyber-attack-and-whats-next . Change Healthcare filed its breach report with the Department on July 19, 2024. ·Breach Portal: Notice to the Secretary of HHS Breach of Unsecured Protected Health Information,· supra note 10. Change Healthcare's breach report currently identifies 100 million individuals as the ·approximate number of individuals affected.· https://ocrportal.hhs.gov/ocr/breach/breach_report.jsf . However, Change Healthcare is still determining the number of individuals affected. The posting on the HHS Breach Portal will be amended if Change Healthcare updates the total number of individuals affected by this breach. ·Change Healthcare Cybersecurity Incident Frequently Asked Questions,· Office for Civil Rights, U.S. Department of Health and Human Services, <https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/index.html> . Back to Citation 215. ··internet Crime Report,· internet Crime Complaint Center, Federal Bureau of Investigation, p. 13 (2023), https://www.ic3.gov/Media/PDF/AnnualReport/2023_IC3Report.pdf . Back to Citation 216. ··Report on Improving Cybersecurity In The Health Care Industry,· supra note 117, p. 16. Back to Citation 217. ·Chon Abraham, et al., ·Muddling through cybersecurity: Insights from the U.S. healthcare industry,· supra note 116, p. 539-548, 540. Back to Citation 218. ··Ransomware Attacks Surge in 2023; Attacks on Healthcare Sector Nearly Double,· The Cyber Threat Intelligence Integration Center, Office of the Director of National Intelligence (Feb. 28, 2024), https://www.dni.gov/files/CTIIC/documents/products/Ransomware_Attacks_Surge_in_2023.pdf . Back to Citation 219. ··Report on Improving Cybersecurity In The Health Care Industry,· supra note 117, p. 14. Back to Citation 220. Id. Back to Citation 221. ·Presidential Memorandum on National Security Memorandum on Critical Infrastructure Security and Resilience supra note 11. Back to Citation 222. ··2024 Data Breach Investigations Report: Healthcare Snapshot,· Verizon Business, p. 12 (May 1, 2024) (The report describes misdelivery as sending information to the wrong recipient, whether by electronic or physical means), <https://www.verizon.com/business/resources/reports/dbir/2024/industries-intro/healthcare-data-breaches/> . Back to Citation

Firewall devices at the edge of a network are sometimes required to do more than block unwanted traffic. A common requirement for these firewalls is to encrypt and decrypt specific network traffic flows between the protected network and external networks. This nearly always involves virtual private networks (VPN), which use additional protocols to encrypt traffic and provide user authentication and integrity checking. VPNs are most often used to provide secure network communications across untrusted networks. For example, VPN technology is widely used to extend the protected network of a multi-site . The planning phase for choosing and implementing a firewall should begin only after an organization has determined that a firewall is needed to enforce the organization's security policy. This typically occurs following a risk assessment of the overall system. A risk assessment includes (1) the identification of threats and vulnerabilities in the information system; (2) the potential impact or magnitude of harm that a loss of confidentiality, integrity, or availability would have on the organization's assets or operations (including mission, function, image, or reputation) in the event of a threat exploitation of identified vulnerabilities; and (3) the identification and analysis of security controls for the information system 20 .

Public Law 115-232 . As provided for in the law, the Under Secretary of Defense for Intelligence and Security, on behalf of the Secretary, granted waivers of NIDs for those categories of proscribed information under the control of the Secretary of Defense, to 20 contractors that met the criteria in summer 2019 with the waivers expiring as of October 1, 2020, since the statute went into effect. Those contractors, pursuant to Section 842 of Public Law 115-232 had to meet the following criteria as part of the waiver determination: (1) A demonstrated successful record of compliance with the NISP assessed by the CSA; and (2) previously been approved for access to proscribed information as indicated in CSA FCL records. The law is limited to ·a person that is a subsidiary located in the United States· (A) for which the ultimate parent entity and any intermediate parent entities of such subsidiary are located in a country that is part of the national technology and industrial base (as defined in section 2500 of title 10, United States Code); and (B) that is subject to the FOCI requirements of the NISP. · Legal Authority for the NISP In addition to E.O. 12829 , which, establishes the NISP and requires the Secretary of Defense to issue and maintain the NISPOM, the following are other relevant authorities for the program. E.O. 10865 ·Safeguarding Classified Information within Industry,· February 20, 1960, as amended (available at <https://www.archives.gov/federal-register/codification/executive-order/10865.html>), addresses the protection of classified information that is disclosed to, or developed by contractors. E.O.

12968 , ·Access to Classified Information,· August 2, 1995, as amended (available at <https://www.govinfo.gov/·content/·pkg/·FR-1995-08-07/·pdf/·95-19654.pdf>), establishes a uniform personnel security program for individuals who will be considered for initial or continued access to classified information. E.O. 13526 , ·Classified National Security Information,· December 29, 2009 (available at <https://www.archives.gov/·files/·isoo/·pdf/·cnsi-eo.pdf>), prescribes a uniform system for classifying, safeguarding and declassifying national security information. E.O. 13587 , ·Structural Reforms to Improve the Security of Classified Networks and the Responsible Sharing and Safeguarding of Classified Information,· October 7, 2011 (available at <https://www.govinfo.gov/·app/·details/·CFR-2012-title3-vol1/·CFR-2012-title3-vol1-eo13587>), directs structural reforms to ensure responsible sharing and safeguarding of classified information on computer networks consistent with (printed page 83304) appropriate protection for privacy and civil liberties. E.O. 13691 ; Promoting Private Sector Cybersecurity Information Sharing,· February 13, 2015 (available at <https://obamawhitehouse.archives.gov/·the-press-office/·2015/·02/·13/·executive-order-promoting-private-sector-cybersecurity-information-sharing>

which happens frequently. This is because a ping in and of itself generally does not adversely affect relevant electronic information systems when it is blocked by firewall policies, and thus does not require activation of the regulated entity's contingency plan. Instead, the business associate would be required to provide such notice in instances where internet commands received by the business associate indicate potential malicious activity, such as a denial of service attack, leading to activation of its contingency plan because of an event that adversely affects the business associate's relevant electronic information systems that create, receive, maintain, or transmit ePHI or adversely affects the confidentiality, integrity, or availability of its ePHI. However, in both such instances, a business associate would still be required to provide notice to the covered entity of the ping as a security incident in accordance with the business associate agreement. [843] The proposal itself would only require that the business associate notify the covered entity of its activation of the contingency plan; it does not include any specific requirements with respect to the form, content, or manner of the notice. Instead, we propose to permit the covered entity and business associate to negotiate such terms and include them in their business associate agreement if they so choose. We recognize that when such an emergency or other occurrence transpires, the focus of the affected regulated entity must be on activating its contingency plan and restoring access to ePHI and the affected relevant electronic information systems. Similarly, when the contingency plan activation is in response to a successful security incident, [844] it may take some time to investigate and determine the cause of the security incident. Thus, this proposal would not require reporting on the cause of the contingency plan activation; it would require reporting solely on the fact that it has activated the plan. Accordingly, we believe that 24 hours would provide a business associate with sufficient time to do all of the following: determine that there is an emergency or other occurrence adversely affecting the business associate's relevant electronic information systems; determine that it needs to activate its contingency plan; identify any covered entities that need to be notified; and notify such covered entities. This proposed requirement to provide notice without unreasonable delay, but no later than 24 hours after a (printed page 983) contingency plan is activated, would also apply when a business associate that is a governmental entity enters into an arrangement with a covered entity that is also a governmental entity where such arrangement meets the requirements of the Privacy Rule at 45 CFR 164.504(e)(3) in accordance with 45 CFR 164.314(a)(2)(ii) and when a business associate enters into a business associate agreement with a subcontractor in accordance with 45 CFR 164.314(a)(2)(iii)

Appropriately scoping security requirements is an important factor in determining protection-234 related investment decisions and managing security risks for nonfederal organizations. If nonfederal organizations designate specific system components to process, store, or transmit CUI associated with a critical program or a high value asset, those organizations may limit the scope of the security requirements by isolating the system components in a separate CUI security domain. Isolation can be achieved by applying architectural and design concepts (e.g., implementing subnetworks with firewalls, software-defined perimeters, micro-segmentation, zero trust network architectures, and information flow control mechanisms). Security domains may employ physical separation, logical separation, or a combination of both. This approach can provide adequate security for CUI and avoid increasing the organization's security posture beyond what it requires to protect its missions, functions, operations, and assets. This publication does not provide guidance on which organizational programs or assets are determined to be critical or of high value.

Those determinations are made by the federal agencies mandating the use of the security requirements for additional protection and can be guided and informed by laws, Executive Orders, directives, regulations, or policies. Additionally, this publication does not provide guidance on specific types of threats or attack scenarios that justify the use of the security requirements. Finally, there is no expectation that all of the security requirements will be needed in every situation. Rather, requirements are selected by federal agencies based on mission needs and risk.

1.2. Organization of This Publication The remainder of this publication is organized as follows: · Section 2 describes the assumptions and methodology used to develop the enhanced security requirements and the organization and structure of the requirements. · Section 3 lists the enhanced security requirements for protecting the confidentiality, integrity, and availability of CUI in nonfederal systems and organizations. The following sections provide additional information to support the protection of CUI: · References · Appendix A: Acronyms · Appendix B: Glossary · Appendix C: Summary of Enhanced Security Requirements · Appendix D: Adversary Effects · Appendix E: Organization-Defined Parameters · Appendix F: Change Log

(iii) Requesters who seek records about themselves that are not contained in a Privacy Act system of records, and who cite or imply only the Privacy Act, will have their requests processed under the provisions of the FOIA (32 CFR part 286), because the access provisions of this part do not apply. Appeals shall be processed under the FOIA. (iv) Requesters who seek records about themselves that are contained in a Privacy Act system of records, and who cite or imply the FOIA or both Acts, will have their requests processed under the provisions of this part and the FOIA (32 CFR part 286). If the system of records is exempt from the access provisions of this part, and if the records, or any portion thereof, are exempt under the FOIA, the requester shall be advised and informed of the appropriate Privacy and FOIA exemption. Appeals shall be processed under both Acts. (v) Requesters who seek records about themselves that are not contained in a Privacy Act system of records, and who cite or imply the Privacy Act and FOIA, will have their requests processed under the FOIA (32 CFR part 286), because the access provisions of this part do not apply. Appeals shall be processed under the FOIA. (2) Do not deny individuals' access to personal information concerning themselves that would otherwise be releasable to them under either Act solely because they fail to cite or imply either Act or cite the wrong Act or part. (3) Explain to the requester which Act(s) was(were) used when granting or denying access under either Act. (j) Time limits. DoD Components normally shall acknowledge requests for access within 10 working days after receipt and provide access within 30 working days. (k) Privacy case file. Establish a Privacy Act case file when required. (See paragraph (p) of §-310.19.) §-310.18 Denial of individual access. (a) Denying individual access. (1) An individual may be denied access to a record pertaining to him or her only if the record: (i) Was compiled in reasonable anticipation of a civil action or proceeding (see §-310.27). (ii) Is in a system of records that has been exempted from the access provisions of this part under one of the permitted exemptions. (See §-310.28 and §-310.29.) (iii) Contains classified information that has been exempted from the access provision of this part under the blanket exemption for such material claimed for all DoD records systems. (See §-310.26(c).). (iv) Is contained in a system of records for which access may be denied under some other Federal statute that excludes the record from coverage of the Privacy Act (5 U.S.C. 552a). (2) Where a basis for denial exists, do not deny the record, or portions of the record, if denial does not serve a legitimate governmental purpose. (b) Other reasons to refuse access: (1) An individual may be refused access if: (i) The record is not described well enough to enable it to be located with a reasonable amount of effort on the part of an employee familiar with the file; or

b. Is an individual appointed to implement the Privacy Act requirements? c. Are provisions of AR 25-71 concerning protection of OPSEC sensitive information regularly brought to the attention of managers responsible for responding to Privacy Act requests and those responsible for control of the Army's records? d. When more than twenty working days are required to respond, is the Privacy Act requester informed, explaining the circumstance requiring the delay and provided an appropriate date for completion. e. Are Accounting Disclosures Logs being maintained? Comments: Assist in making this a better tool for evaluating management controls. Submit comments to the Department of Army, Freedom of Information and Privacy Division. Appendix H to Part 505-Definitions Function (a) Access. Review or copying a record or parts thereof contained in a Privacy Act system of records by an individual. (b) Agency. For the purposes of disclosing records subject to the Privacy Act, Components of the Department of Defense are considered a single agency. For other purposes including access, amendment, appeals from denials of access or amendment, exempting systems of records, and recordkeeping for release to non-DOD agencies, the Department of the Army is considered its own

agency. (c) Amendment. The process of adding, deleting, or changing information in a system of records to make the data accurate, relevant, timely, or complete. (d) Computer Matching Agreement. An agreement to conduct a computerized comparison of two or more automated systems of records to verify eligibility for payments under Federal benefit programs or to recover delinquent debts for these programs. (e) Confidential Source. A person or organization who has furnished information to the Federal Government under an express promise that the person's or the organization's identity would be held in confidence or under an implied promise of such confidentiality if this implied promise was made before September 27, 1975. (f) Cookie. A mechanism that allows the server to store its own information about a user on the user's own computer. Cookies are embedded in the HTML information flowing back and forth between the user's computer and the servers. They allow user-side customization of Web information. Normally, cookies will expire after a single session. (g) Defense Data Integrity Board. The Board oversees and coordinates all computer matching programs involving personal records contained in systems of records maintained by the DOD Component; reviews and approves all computer matching agreements between the Department of Defense (DOD) and other Federal, State, and local governmental agencies, as well as memoranda of understanding when the match is internal to the DOD. (h) Disclosure.

The electronic content generated or transmitted during a telemedicine visit constitutes ePHI, so the increase in telemedicine further increases the amount of PHI that is also ePHI. It is not only the ePHI maintained in EHRs and other electronic recordkeeping systems that faces security risks. Medical equipment and devices are increasingly connected through one or more networks, which means that any issues affecting the network likely will affect the medical equipment and devices. [177] And some medical equipment and devices rely on off-the-shelf operating systems, such as Windows, Linux, and similar third-party software; [178] thus, the medical equipment and devices can experience the same vulnerabilities as personal computing devices. Generally, the U.S. Food & Drug Administration (FDA) does not need to review software patches or configuration updates for off-the-shelf software before a device manufacturer puts them in place because the FDA views most patches and configuration updates as design changes that can be made without prior discussion. [179] Cybercriminals may use or target technology assets, such as software or medical devices used for treating individuals. For example, in 2021, a cyberattack on cloud-based systems supplied by a particular company compromised the ePHI of more than 200,000 individuals and affected the software for linear accelerators used in radiotherapy, leading to disruptions to cancer treatment. [180] Thus, to protect technology assets used for treatment, the information systems that create, receive, maintain, and transmit ePHI also must be protected. As another example, in 2013, the Mayo Clinic [181] hired a group of ethical hackers [182] to identify vulnerabilities in 40 different medical devices. [183] The hackers were able to gain access to all of the devices, meaning that the devices could all be vulnerable to a cyberattack. [184] Such attacks may create an opening for a subsequent attack on the device itself or on the regulated entity's information systems that create, receive, maintain, or transmit ePHI, compromising those information systems and the ePHI itself. [185] It also may lead, intentionally or not, to a loss of device integrity, which could result in the corruption of the device's functionality or the ePHI on the device. [186] A cyberattack on a medical device may also reduce the ability of the authorized person to use the device (e.g., a denial of service attack, which is a type of cyberattack that overloads the device by flooding the network with traffic). [187] Depending on the device and its use, the result of cyberattacks on a medical device could range from little or no effect to serious injury or death. [188] According to researchers at Brown University, medical devices are a prime target for cybercriminals. In fact, they believe, "More than just technically feasible, the widespread takedown of medical devices is an imminent threat." [189]

This standard specifies the stateless hash-based digital signature algorithm (SLH-DSA). Digital signatures are used to detect unauthorized modifications to data and to authenticate the identity of the signatory. In addition, the recipient of signed data can use a digital signature as evidence in demonstrating to a third party that the signature was, in fact, generated by the claimed signatory. This is known as non-repudiation since the signatory cannot easily repudiate the signature at a later time. SLH-DSA is based on SPHINCS + , which was selected for standardization as part of the NIST Post-Quantum Cryptography Standardization process.

1. Name of Standard. Stateless Hash-Based Digital Signature Standard (FIPS 205).
2. Category of Standard. Computer Security. Subcategory. Cryptography.
3. Explanation. This standard specifies a stateless hash-based digital signature scheme (SLHDSA) for applications that require a digital signature rather than a written signature. Additional digital signature schemes are specified and approved in other NIST Special Publications

We characterize the uncertainty in the estimate of the time for preventive action as a Beta-Pert distribution with the most likely value of 78 and the minimum and maximum values (taken from the data) of 6 days and 150 days. The Beta-Pert distribution is a Beta distribution that has been re-scaled to run between values other than 0 and 1. The Beta-Pert uses a minimum, maximum, and most likely value to generate a distribution running from the minimum to the maximum, with a mean equal to (minimum + (4 times the most likely) + maximum) divided by 6. We use the Beta-Pert distribution since it is less sensitive to extreme values and generates more outcomes close to the mean than a Triangular distribution. We assume that the average duration of outbreaks that persist beyond the time for preventive action is distributed normally with a mean of 121 minus the time for preventive action, and a standard deviation (computed from the data) of 17. We assume a uniform distribution with a range between 0.15 and 0.18 in the estimate in the portion of annual illnesses that potentially could be averted by faster preventive action.

11. Estimating the Impact on Traceback Performance for Options With Different Coverage

Our framework for estimating the impact on baseline traceback speeds and completion rates for policy options with alternative levels of coverage uses the number of facilities in each sector to weight the sectoral contribution to baseline traceback performance. We adjusted the weights of the transportation, warehouse, and mixed-type facilities sectors to account for special considerations related to their contributions to traceback speeds and completion rates. For options that distinguish between very small and large facility coverage, we also adjusted (printed page 71626) the contributions to traceback performance by facility size. We estimated that options with the most comprehensive coverage will lead to the greatest decrease in times for preventive action, and eliminate the largest number of investigations that are prematurely terminated for reasons of poor records quality or nonexistent records. Options with more limited coverage will have a more limited impact on traceback speeds and completion rates. The factors used to scale baseline traceback speeds and rates of premature terminations are described by the following expression: Total baseline performance = contribution by grocery outlets, given that contamination occurred further up the supply chain + contribution by wholesalers and importers, given that contamination occurred further up the supply chain + contribution by warehouses, given that contamination occurred further up the supply chain + contribution by manufacturers, given that contamination occurred further up the supply chain + contribution by transporters, given that contamination occurred further up the supply chain + contribution by mixed-type facilities.

[illegible]

users, services, and hardware and managed commensurate with the assessed risk of unauthorized access | Medium | N1: See the notes for PR. | | PR.AA-01 | Identities and credentials for authorized users, services, and hardware are managed by the organization | Medium | N1: See the notes for PR. | | PR.AA-02 | Identities are proofed and bound to credentials based on the context of interactions | Medium | N1: See the notes for PR.

) Escorts are responsible for ensuring that the classified material being shipped is safeguarded in the event of an emergency stop en route, re-routing of the aircraft, or in the event that the recipient government's representative fails to meet the shipment at its destination. (4) The contractor does not have to provide escorts if: (i) The classified material is shipped by the Defense Transportation System or a U.S. military carrier. (ii) The recipient government DGR has signed for the receipt of the classified material within the United States. (iii) The classified material is shipped via a military carrier of the recipient government or a carrier owned by or registered to the recipient government. (iv) The classified material is shipped via a cleared U.S. commercial freight carrier, so long as the contractor has a written agreement from the U.S. commercial freight carrier to provide an escort who is eligible for access to classified information and has access to classified information at the classification level of the material being shipped. (v) There are exceptional circumstances, and procedures have been approved by both the USG and the recipient government. (3) Secure communications plan. (i) The contractor is required to meet all requirements outlined in this section, as applicable, for the secure communications plan. (ii) The secure communications plan may be approved within a program security instruction, SSP, or a government to government agreement by the designated security authorities. A separate memorandum of understanding or memorandum of agreement is not required. (iii) Additionally, an SSP must be authorized in accordance with §.117.18 and the CSA provided guidance. (4) Return of material for repair, modification, or maintenance. (i) A foreign government or foreign contractor may return classified material to a U.S. contractor for repair, modification, or maintenance. (ii) The approved methods of return will be specified in either the GCA sales arrangement, the security requirements section of a direct commercial sales arrangement or, in the case of material transferred as freight, in the original TP. (iii) The contractor, on receipt of notification that classified material is to be received, will notify the applicable CSA. (5) Use of freight forwarders. (i) A commercial freight forwarder may be used to arrange for the international transfer of classified material as freight. (A) The freight forwarder must be under contract to a USG agency, U.S. contractor, or the recipient foreign government. (B) The contract will describe the specific functions to be performed by the freight forwarder. (C) The responsibility for security and control of the classified material that is processed by freight forwarders remains with the USG until the freight is transferred to a DGR of the recipient government.

) OSAs must have a System Security Plan (SSP) (CMMC security requirement CA.L2-3.12.4) in place at the time of assessment to describe each information system within the CMMC Assessment Scope. The absence of an up to date SSP at the time of the assessment would result in a finding that ` an assessment could not be completed due to incomplete information and noncompliance with 48 CFR 252.204-7012 . ' (6) For each NOT MET security requirement the OSA must have a POA&M in place. A POA&M addressing NOT MET security requirements is not a substitute for a completed requirement. Security requirements not implemented, whether described in a POA&M or not, is assessed as `NOT MET.' (7) Specialized Assets must be evaluated for their asset category per the CMMC scoping guidance for the level in question and handled accordingly as set forth in §.170.19. (8) If an OSC previously received a favorable adjudication from the DoD CIO indicating that a security requirement is not applicable or that an alternative security measure is equally effective (in accordance with 48 CFR 252.204-7008 or 48 CFR 252.204-7012), the DoD CIO adjudication must be included in the system security plan to receive consideration during an assessment. A security requirement for which implemented security measures have been adjudicated by the DoD CIO as equally effective is assessed as MET if there have been no changes in the environment. (ii) CMMC Level 2 Scoring Table. CMMC Level 2 scoring has been assigned based on the methodology set forth in table 1 to this paragraph (c)(2)(ii). Table 7 to §.170.24 (c)(2)(ii) -CMMC Level 2 Scoring Table CMMC Level 2 requirement categories Point value subtracted from maximum score Basic Security Requirements: If not implemented, could lead to significant exploitation of the network, or exfiltration of CUI 5 If not implemented, has specific and confined effect on the security of the network and its data 3 Derived Security Requirements: If not implemented, could lead to significant exploitation of the network, or exfiltration of CUI 5 If not completely or properly

implemented, could be partially effective and points adjusted depending on how the security requirement is implemented: 3 or 5 ·Partially effective implementation·3 points. ·Non-effective (not implemented at all)·5 points. If not implemented, has specific and confined effect on the security of the network and its data 3 If not implemented, has a limited or indirect effect on the security of the network and its data 1 (3) CMMC Level 3 assessment scoring methodology.

CMMC Program rule to the supplemental documents, which are not codified. As such, the supplemental documents are provided for optional use, and the regulatory text takes precedence. The CMMC Assessment Process (CAP) guidance is a product of the Accreditation Body and is not codified in the CFR as part of the CMMC rule, and the regulatory text in part 170 takes precedence. Comments on the CMMC Supplemental Guidance were received as part of the public comment period review. Final versions of these documents were published with this rule. Other supplemental materials published by the Accreditation Body do not convey government direction and are therefore do not require rulemaking. Supplemental documents (e.g., CMMC assessment and scoping guides) are not codified in the CFR as part of the regulatory text. To codify CMMC program requirements, content must be included in the 32 CFR part 170 CMMC Program rule text. DoD developed the CMMC Assessment Guides to provide supplemental information to the public offering added clarity on the intent of the NIST SP 800-171A Jun2018 and NIST SP 800-172A Mar2022 guides. The CMMC Assessment Guides are particularly important for security requirements with organization-defined parameters (ODPs) (e.g., CMMC Level 3). There is no requirement to use the supplemental guidance documents. Office of the Federal Register (OFR) regulations, at 1 CFR part 51 , govern the IBR process. IBR is only available if the applicable regulations are published in the Federal Register and codified in the CFR. When incorporated by reference, this material has the force and effect of law, as do all regulations published in the Federal Register and codified in the CFR. 1 CFR part 51 requires the specification of a revision to a standard, for example NIST SP 800-171, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, Revision 2, February 2020 (includes updates as of January 28, 2021), which is incorporated by reference in this rule. The DoD will determine when to update this rule after documents incorporated by reference have been revised. Per OFR guidance, § 170.4 points to other sections of part 170 where applicable and repeats definitions for terms incorporated by reference. Contractors complying with CMMC requirements need to be familiar with those documents that are incorporated (printed page 83161) by reference. The definition of subcontractor is not incorporated by reference, but rather points to a definition codified in 48 CFR 3.502-1 , as recommended in OMB guidelines for formal rulemaking. DoD has determined that the Defense Information Systems Agency's Cloud Security Technical Reference Architecture does not meet the criteria for approved IBR material. However, the rule has been updated to use a different definition for Cloud Service Provider. The requirements of NARA's CUI program (32 CFR part 2002) and DoD's implementing policies for identifying and managing CUI are beyond the scope of the CMMC rule.

Amendment of records. (a) Amended records. (1) Individuals are encouraged to periodically review the information maintained about them in Privacy Act systems of records and to familiarize themselves with the amendment procedures established by this part. (2) An individual may request to amend records that are retrieved by his or her name or personal identifier from a system of records unless the system has been exempted from the amendment provisions of the Act. The standard for amendment is that the records are inaccurate as a matter of fact rather than judgment, irrelevant, untimely, or incomplete. The burden of proof is on the requester. (3) The system manager or custodian must review Privacy Act records for accuracy, relevance, timeliness, and completeness. (4) Amendment procedures are not intended to permit individuals to challenge events in records that have actually occurred. Amendment procedures only allow individuals to amend those items that are factually inaccurate and not matters of official judgment (e.g. , performance ratings, promotion potential, and job performance appraisals). In addition, an individual is not permitted to amend records for events that have been the subject of judicial or quasi-judicial actions/proceedings. (b) Proper amendment requests. (1) Amendment requests, except for routine administrative changes, will be in writing. (2) When acting on behalf of a first party requester, an individual must provide written documentation of the first party requester's consent to allow the individual to view his or her records. (3) Amendment is appropriate if it can be shown that: (i) Circumstances leading up to the recorded event were found to be inaccurately reflected in the document; (ii) The record is not identical to the individual's copy; or (iii) The document was not constructed in accordance with the applicable recordkeeping requirements prescribed in AR 25-400-2, The Army Records Information Management System (ARIMS). (4) Under the amendment provisions, an individual may not challenge the merits of an adverse determination. (5) U.S. Army Criminal Investigation

Command (USACIDC) reports of investigations (PA system of records notice A0195-2a USACIDC, Source Register; A0195-2b USACIDC, Criminal Investigation and Crime Laboratory Files) have been exempted from the amendment provisions of the Privacy Act. Requests to amend these reports will be considered under AR 195-2. Actions taken by the Commander of U.S. Army Criminal Investigation Command will constitute final action on behalf of the Secretary of the Army under that regulation. (6) Records placed in the National Archives are exempt from the Privacy Act provision allowing individuals to request amendment of records. Most provisions of the Privacy Act apply only to those systems of records that are under the legal control of the originating agency; for example, an agency's current operating files or records stored at a Federal Records Center.

(2) The agency may release outside the Government Contractor bid or proposal information, Contractor proprietary business information, and contractor-attributional information that is not created by or for the Government, but that is related to a CUI incident: (i) To entities with missions that may be affected by such information; (ii) To entities that may be called upon to assist in the diagnosis, detection, or mitigation of CUI incidents; or (iii) For national security purposes, including cyber situational awareness. (3) The Government may use and release Contractor bid or proposal information, Contractor proprietary business information, and contractor-attributional information, created by or for the Government and related to a CUI incident, outside of the Government for purposes and activities associated with responding to a CUI incident and for any other lawful Government purpose or activity. (4) In any authorized release, the Government will include the Contractor proprietary business information or contractor-attributional information only to the extent necessary, as determined by the Government, to advance a lawful Government purpose or activity. (e) Subcontracts. The Contractor shall include this clause, including this paragraph (e) and without alteration except to identify the parties, in all subcontracts and other contractual instruments. The Contractor shall require subcontractors to notify the prime Contractor or next higher tier subcontractor within 8 hours of discovery of a suspected or confirmed CUI incident. (End of clause) 42. Amend section 52.212-5 by: a. Revising the date of the clause; b. Redesignating paragraphs (b)(12) through (65) as paragraphs (b)(14) through (67) and adding new paragraphs (b)(12) and (13); c. Redesignating paragraphs (e)(1)(viii) through (xxvii) as paragraphs (e)(1)(x) through (xxix) and adding new paragraphs (e)(1)(viii) and (ix); d. In Alternate II: i. Revising the date of the alternate; and ii. Redesignating paragraphs (e)(1)(ii)(H) through (Z) as paragraphs (e)(1)(ii)(J) through (BB); and iii. Adding new paragraphs (H) and (I). The revisions read as follows: (printed page 4301) 52.212-5 Contract Terms and Conditions Required To Implement Statutes or Executive Orders-Commercial Products and Commercial Services. * * * * * Contract Terms and Conditions Required To Implement Statutes or Executive Orders-Commercial Products and Commercial Services (DATE) * * * * * (b) * * * (12) 52.204-XX, Controlled Unclassified Information (DATE) (E.O. 13556). (13) 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information (DATE). * * * * * (e)(1) * * * (viii) 52.204-XX, Controlled Unclassified Information (DATE) (E.O. 13556). (ix) 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information (DATE). * * * * * Alternate II (DATE) * * * (e)(1) * * * (ii) * * * (H) 52.204-XX, Controlled Unclassified Information (DATE) (E.O. 13556).

3.1.3 | The acct File | 26 | | 3. 3.1.3 The acct File The file /usriadmiacct [Sun88a, 1344-1345] records each execution of a command on the system, who executed it, when, and how long it took.

Some comments received lacked relevance to the rule's content, which is limited to specific CMMC Program requirements. The DoD declines to respond to speculative or editorial comments about private citizens or entities, all of which are not within the scope of this rule. Personnel actions taken by the CMMC AB and comments regarding filing of IRS forms are not within the scope of this rule. §170.8(b) of this final rule provides requirements of the CMMC AB. CMMC Program requirements as described in this rule requires the CMMC Accreditation Body and the CAICO to have and abide by ethics and conflicts of interest rules and to have and maintain a Code of Professional Conduct (CoPC). §170.8(b)(3) describes the ISO/IEC requirements and the timeline in which the CMMC AB needs to meet those requirements. The DoD declines to comment on business decisions made by the current CMMC AB in the performance of its CMMC related roles, responsibilities, and requirements. Based on information currently known to DoD, the CMMC AB is currently performing as defined in this final rule and the terms of the contract. The ANSI National Accreditation Body is performing the function of accrediting the CAICO, which is appropriate given its status as a subsidiary of the CMMC AB. The DoD defined CMMC Conflict of Interest requirements to reduce the possibility that a member of the

CMMC Ecosystem acting in one capacity may bias, or be biased by, clients that are paying them to perform another CMMC related service. The rule text includes ethics requirements for members of the CMMC ecosystem, to include the CMMC AB (§ 170.8). The DoD concurred with some comments and has increased the cooling off period from six months to one year in § 170.8(b)(17)(i)(C). DoD considered many alternatives before deciding upon the current CMMC structure. The DoD has established requirements for a CMMC Accreditation Body, and this accreditation body will administer the CMMC Ecosystem. The phased CMMC implementation plan provides time to train the necessary number of assessors and, the rule has been updated to add an additional six months to the Phase 1 timeline. (printed page 83126) The DoD requires that the Accreditation Body must achieve and maintain compliance with the ISO/IEC 17011:2017(E) standard (the international benchmark used in demonstrating an accreditation body's impartiality, technical competency, and resources) and the requirements set forth in § 170.8. The CMMC Proposed rule also requires compliance with ISO/IEC 17020:2012(E) for conformity assessments. § 170.12(b)(5) was revised to indicate that a CMMC instructor, subject to the Code of Professional Ethics and Conflict of Interest policies, may serve on an assessment team but cannot consult. CCIs are not permitted to develop or proctor exams to avoid participating in any activity, practice, or transaction that could result in an actual or perceived conflict of interest.

DoD considered many alternatives before deciding upon the current CMMC structure. The DoD established requirements for a CMMC Accreditation Body, and this accreditation body will administer the CMMC Ecosystem. The DoD reviewed and assessed the whitepapers that were submitted by RFI respondents and determined that no single respondents could meet all the broad facets required to serve as the CMMC Accreditation Body. Based on this assessment, the DoD published notice of a planned meeting in November 2019 to allow the respondents and other members of the public to hear the senior DoD leadership address DoD perspectives regarding the notional CMMC implementation flow; the notional program structure; the notional CMMC Accreditation Body activities, structure, and relationship with the DoD; and the notional CMMC implementation schedule. The DoD also provided information regarding the Department's planned way forward. The result of the November 2019 meeting was the establishment of the current CMMC Accreditation Body. The relationship between the current CMMC Accreditation Body and the DoD was formalized through a Memorandum of Understanding and then a No-Cost Contract. The DoD cannot assume the risk or the workload of directly managing the CMMC Ecosystem or the other alternatives suggested. The current CMMC Accreditation Body is aligned to the DoD through contractual arrangements. 31. Rulemaking Process Comment: Some comments were submitted to identify problems with using the Federal eRulemaking Portal (at www.regulations.gov) or the Federal Register website and did not address content of the proposed rule. One commenter was confused by the identification of the rule as 'Proposed' rather than final. Another asked whether the rule could be republished with page numbers. Many comments critiqued the format, heading and section numbering, use of incorporation by reference, or sections contained within the rule, rather than the substance of the content. For example, some comments described the CMMC rule as overly repetitive or containing duplicative sections. Some comments recommended deleting specific sections to shorten or simplify the rule, including 'History of the Program'. Some commenters perceived the preamble to the rule as unnecessary and recommended deleting or shortening that section. In addition, one commenter noted that responses to public comments received against an earlier CMMC rule publication ought to be published with the 48 CFR part 204 CMMC Acquisition rule rather than this 32 CFR part 170 CMMC Program rule. Several commenters simply thought the rule text too verbose and recommended rewriting the content with fewer words and simpler language or using tables to shorten the content. One comment criticized the organization of the documents.

the entity is under U.S. control), but the foreign interest is entitled to representation on the entity's governing board, an SCA may be adequate. At least one cleared U.S. citizen must serve as an outside director on the entity's governing board. There are no access limitations under an SCA. (iii) SSA. When a foreign interest effectively owns or controls an entity, an SSA may be adequate. An SSA is an arrangement that, based upon an assessment of the source and nature of FOCI and FOCI factors, imposes various industrial security measures within an institutionalized set of entity practices and procedures. The SSA preserves the foreign owner's right to be represented on the entity's board or governing body with a direct voice in the entity's business management, while denying the foreign owner majority representation and unauthorized access to classified information. (A) Requirement for a National Interest Determination (NID). Unless otherwise prohibited by law or regulation (e.g., Section 842 of Pub. L. 115-232), the applicable CSA must determine whether allowing an entity access to proscribed information under an SSA is consistent with national

security interests of the U.S. with concurrence from controlling agencies, as applicable. Such NIDs will be made as part of an entity eligibility determination or because of a changed condition when a GCA requires an entity to have access to proscribed information and the CSA proposes an SSA as the mitigation measure. The NID can be program, project, or contract specific. (B) NID process: (1) The CSA makes a NID for TOP SECRET or SAP information to which the entity requires access. Contractors should be aware that DOE Order 470.4B provides additional information and requirements for processing NID requests for access to RD. (2) In cases in which any category of the proscribed information is controlled by another agency (ODNI for SCI, DOE for RD, the National Security Agency (NSA) for COMSEC), the CSA asks that controlling agency to concur or non-concur on the NID for that category of information. (3) The CSA informs the GCA and the entity when the NID is complete. In cases involving SCI, RD, or COMSEC, the CSA also informs the GCA and the entity when a controlling agency concurs or non-concurs on that agency's category of proscribed information. The entity may begin accessing a category of proscribed information once the CSA informs the GCA and the entity that the controlling agency concurs, even if other categories of proscribed information are pending concurrence. (4) An entity's access to SCI, RD, or COMSEC remains in effect so long as the entity remains eligible for access to classified information and the contract or agreement (or program or project) which imposes the requirement for access to those categories of proscribed information remains in effect, except under any of the following circumstances: (i

The DoD has designed CMMC Program requirements to apply to those contractors that bid for DoD work which will require access to process, store, or transmit FCI or CUI in a contractor owned information system. A CMMC certification assessment is portable in the sense that it provides confidence that the holder has been assessed by an authorized third party for compliance with the applicable security standards (e.g., NIST SP 800-171 R2 or NIST SP 800-172 Feb2021). Once attained, CMMC certification assessment status may be presented for consideration by any entity as an indicator that they have implemented security requirements associated with the certificate level (e.g., NIST SP 800-171 R2 or NIST SP 800-172 Feb2021). Section 170.20 delineates the only existing bases for accepting alternate standards in this rule.- It is beyond the scope of this rule to provide a specific set of directions or guidance on recognition for alternate cybersecurity standards. Deviations from DFARS clauses are also beyond the scope of this rule. Section 170.20 has been modified to state that an OSC with a perfect score from a prior DCMA DIBCAC High Assessment aligned with the same CMMC Level 2 Scoping may meet CMMC Final Level 2 certification assessment requirements via acceptance of the prior DIBCAC assessment in lieu of a C3PAO assessment. Standards Acceptance does not refer to international standards acceptance, which is not described within the rule. c. C3PAO, CCP, and CCA Requirements Comment: In addition to the interest in international agreements, some commenters expressed concern about CMMC ecosystem capacity to meet demand for Level 2 certification. They advocated support for accreditation of non-U.S. based C3PAOs. One commenter suggested that FOCI requirements be deleted from the rule and managed via DoD's oversight of the CMMC AB. One commenter speculated the phased CMMC implementation plan would require all non-U.S. firms to comply simultaneously and recommended that foreign contractors be allowed additional time to comply. Another recommended that foreign companies be permitted to simply self-assess in lieu of obtaining a CMMC Level 2 certification assessment. Several commenters asked about foreign nationals participating in the CMMC ecosystem and noted discrepancies between qualifications identified in the rule and content on the CMMC AB's website at the time of rule publication. These commenters expressed interest in the ability for foreign citizens to become CCAs, CCPs, and LTPs (a term no longer used in the rule).

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204, 208, 209, 212, 213, 215, 216, and 252 [Docket DARS-2020-0027] RIN 0750-AK44 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to update the policy and procedures for use of the Supplier Performance Risk System and to require contracting officers to consider SPRS risk assessments, if available, in the evaluation of a supplier's quotation or offer and to consider SPRS supplier risk assessments when determining

contractor responsibility. DATES: Effective March 22, 2023. FOR FURTHER INFORMATION CONTACT: Heather Kitchens, telephone 571-296-7152. SUPPLEMENTARY INFORMATION: I. Background DoD published a proposed rule in the Federal Register at 85 FR 53748 on August 31, 2020, to amend the DFARS to require contracting officers to consider Supplier Performance Risk System (SPRS) risk assessments during evaluation of quotations or offers and to consider the SPRS supplier risk assessment in the evaluation of contractor responsibility. Two respondents submitted public comments in response to the proposed rule. II. Discussion and Analysis DoD reviewed the public comments in the development of the final rule. A discussion of the comments and the changes made to the rule as a result of those comments is provided, as follows. A. Summary of Significant Changes From the Proposed Rule As a result of public comments, there are changes from the proposed rule in the final rule to clarify applicability of the rule. Additionally, editorial and clarifying changes were made in the final rule as discussed in paragraph C of this preamble. B. Analysis of Public Comments a. Solicitation Provision Applicability Comment: One respondent commented that the prescription for solicitation provision 252.204-70XX, Notice to Prospective Suppliers on the Use of the Supplier Performance Risk System in Performance Evaluations, should be updated at DFARS 204.7X04 to state that the provision is for use in solicitations using FAR part 13 simplified acquisition procedures, including solicitations for supplies and services using FAR part 12 procedures for the acquisition of commercial items, to align with DFARS 204.7X02, Applicability. Response:

All CMMC ecosystem members are required to abide by the appropriate ethics and conflicts of interest policies established by the CMMC AB and CAICO. Rule content pertaining to ethics, quality assurance functions, record keeping, data encryption, security, etc. functions across the ecosystem are tailored to reflect the role each entity fills in the ecosystem. The CMMC AB is not an agency of the Federal government; it is a private sector organization operating under contract with the DoD. As described in § 170.6(a), the Office of the Department of Defense Chief Information Officer (DoD CIO) provides oversight of the CMMC Program and is responsible for establishing CMMC assessment, accreditation, and training requirements as well as developing and updating CMMC Program implementing guidance. The Accreditation Body must be under contract with the DoD. The rule has been modified to include additional CMMC AB oversight responsibilities for the CMMC PMO. The Department declines to incorporate CMMC AB generated artifacts into the rule by reference. The responsibilities of the DoD CIO and CMMC PMO are outlined in § 170.6 and the responsibilities of the Accreditation Body are outlined in § 170.8. The DoD acknowledges that the CMMC AB may not offer both accreditation services and certification services. DoD declines to make edits to these sections as they are in alignment with the roles and responsibilities of the CMMC AB. The DoD has revised § 170.8(b)(17)(i)(C) in the rule to clarify that the ‘CMMC activities’ which former Accreditation Body members are prohibited from include any or all responsibilities described in Subpart C of this rule. The rule was updated to indicate that C3PAOs must also meet administrative requirements as determined by the CMMC AB. It was also updated to clarify that the term ‘independent assessor staff’ in § 170.8(b)(4) refers to independent CMMC Certified Assessor staff, and to clarify the meaning of the term ‘members’ at § 170.8(b)(17)(i)(B). DoD declines to modify § 170.8(b)(15) to include the phrase ‘technical accuracy and alignment with all applicable legal, regulatory, and policy requirements’, as this does not result in a substantive change to the requirements as currently specified. c. C3PAOs Comment:

may wish to closely follow the development of these new publications by NIST. Organizations are encouraged to review all draft publications during public comment periods and provide feedback to NIST. Many NIST cybersecurity publications, other than the ones noted above, are available at <https://csrc.nist.gov/publications>. ## Authority This publication has been developed by NIST in accordance with its statutory responsibilities under the Federal Information Security Modernization Act (FISMA) of 2014, 44 U.S.C. § 3551 et seq., Public Law (P.L.) 113-283. NIST is responsible for developing information security standards and guidelines, including minimum requirements for federal information systems, but such standards and guidelines shall not apply to national security systems without the express approval of appropriate federal officials exercising policy authority over such systems. This guideline is consistent with the requirements of the Office of Management and Budget (OMB) Circular A-130. Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority. Nor should these guidelines be interpreted as altering or superseding the existing authorities of the Secretary of Commerce, Director of the OMB, or any other federal official. This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.

d. The cost of the safeguard under consideration. 2. Label or designate media products containing personal information that do not contain classified material in such a manner as to alert those using or handling the information of the need for special protection. Designating products ·For Official Use Only· in accordance with the requirements of DoD 5200.1-R satisfies this requirement. 3. Mark and protect all computer products containing classified data in accordance with the requirements of DoD 5200.1-R and DoD Directive 8500.1. 4. Mark and protect all computer products containing ·For Official Use Only· material in accordance with the requirements of DoD 5200.1-R. 5. Ensure that safeguards for protected information stored at secondary sites are appropriate. 6. If there is a computer failure, restore all protected information being processed at the time of the failure using proper recovery procedures to ensure data integrity. 7. Train personnel involved in processing information subject to this Regulation in proper safeguarding procedures. D. Physical Safeguards 1. For all unclassified facilities, areas, and devices that process information subject to this Regulation, establish physical safeguards that protect the information against reasonably identifiable threats that could result in unauthorized access or alteration. 2. Develop access procedures for unclassified computer rooms, tape libraries, micrographic facilities, decollating shops, product distribution areas, or other direct support areas that process or contain personal information subject to this Regulation that control adequately access to these areas. 3. Safeguard on-line devices directly coupled to IT systems that contain or process information from systems of records to prevent unauthorized disclosure, use, or alteration. 4. Dispose of paper records following appropriate record destruction procedures. (See §.310.13(c) and DoD 5200.1-R.) E. Technical Safeguards 1. Components are to ensure that all PII not explicitly cleared for public release is protected according to Confidentiality Level Sensitive, as established in DoD Instruction 8500.2. In addition, all DoD information and data owners shall conduct risk assessments of compilations of PII and identify those needing more stringent protection for remote access or mobile computing. 2. Encrypt unclassified personal information in accordance with current Information Assurance (IA) policies and procedures, as issued. 3. Remove personal data stored on magnetic storage media by methods that preclude reconstruction of the data. 4. Ensure that personal information is not inadvertently disclosed as residue when transferring magnetic media between activities. 5. Only DoD authorized devices shall be used for remote access. Any remote access, whether for user or privileged functions, must conform to IA controls specified in DoD Instruction 8500.2. 6. Remote access for processing PII should comply with the latest IA policies and procedures.

(B) Penetration testing must be performed at least once every 12 months or in accordance with the covered entity's or business associate's risk analysis required by §.164.308(a)(2), whichever is more frequent. (iv) Patch and update installation. Deploy technical controls in accordance with the covered entity's or business associate's patch management program under §.164.308(a)(4) to ensure timely installation of software patches and critical updates as reasonable and appropriate. (i) Standard: Data backup and recovery ·(1) General. Deploy technical controls to create and maintain exact retrievable copies of electronic protected health information. (2) Implementation specifications ·(i) Data backup. Create backups of electronic protected health information in accordance with the policies and procedures required by §.164.308(a)(13)(ii)(B) and with such frequency to ensure retrievable copies of electronic protected health information are no more than 48 hours older than the electronic protected health information maintained in the covered entity or business associate's relevant electronic information systems. (ii) Monitor and identify. Deploy technical controls that, in real-time, monitor, and alert workforce members about, any failures and error conditions of the backups required by paragraph (i)(2)(i) of this section. (iii) Record. Deploy technical controls that record the success, failure, and any error conditions of backups required by paragraph (i)(2)(i) of this section. (iv) Testing. Restore a representative sample of electronic protected health information backed up as required by paragraph (i)(2)(i) of this section, and document the results of such test restorations at least monthly. (j) Standard: Information systems backup and recovery. Deploy technical controls to create and maintain backups of relevant electronic information systems; and review and test the effectiveness of such technical controls at least once every six months or in response to environmental or operational changes,

whichever is more frequent, and modify as reasonable and appropriate. § 164.314 Organizational requirements. (a)(1) Standard: Business associate contracts or other arrangements. The contract or other arrangement required by § 164.308(b)(2) must meet the requirements of paragraph (a)(2)(i), (ii), or (iii) of this section, as applicable. (2) Implementation specifications ·(i) Business associate contracts. The contract must provide that the business associate will do all of the following: (A) Comply with the applicable requirements of this subpart. (B) In accordance with § 164.308(b)(1)(ii), ensure that any subcontractors that create, receive, maintain, or transmit electronic protected health information on behalf of the business associate agree to comply with the applicable requirements of this subpart by entering into a contract or other arrangement that complies with this section.

that the Secretary of Defense issue and maintain this rule and changes to it. The USD(I&S) does so in consultation with all affected agencies (E.O. 12829 section 201), with the concurrence of the Secretary of Energy, the Chairman of the NRC, the DNI, and the Secretary of Homeland Security (E.O.12829 section 201), and in consultation with the ISOO Director (E.O. 12829 section 102). (2) Acts as the CSA for DoD. (3) Provides policy and management of the NISP for non-DoD executive branch agencies who enter into inter-agency security agreements with DoD to provide industrial security services required when classified information is disclosed to contractors in accordance with E.O. 12829 , as amended. (b) Director, DCSA. Under the authority, direction, and control of the USD(I&S), and in accordance with DoDI 5220.22 and DoD Directive (DoDD) 5105.42, ·Defense Security Service (DSS)· [1] (available at: <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodd/510542p.pdf?ver=2019-01-14-090012-283>) the Director, DCSA: (1) Oversees and manages DCSA, which serves as the DoD CSO. (2) Administers the NISP as a separate program element on behalf of DoD GCAs and those agencies with agreements with DoD for security services. (3) Provides security oversight of the NISP as the DoD CSO on behalf of DoD components and those non-DoD executive branch agencies who enter into agreements with DoD as noted in paragraph (a)(3) of this section. The Director, DCSA, will be relieved of this oversight function for DoD special access programs (SAPs) when the Secretary of Defense or the Deputy Secretary of Defense approves a carve-out provision in accordance with DoDD 5205.07, ·DoD SAP Policy· (available at: <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodd/520507p.pdf?ver=2020-02-04-142942-827>). (c) Secretary of Energy. In addition to the responsibilities in paragraph (h) of this section, the Secretary of Energy: (1) Prescribes procedures for the portions of this rule pertaining to information classified under the AEA (i.e., RD, FRD, and TFNI), as nothing in the rule shall be construed to supersede the authority of the Secretary of Energy under the AEA. (2) Retains authority over access to information classified under the AEA. (3) Inspects and monitors contractor, licensee, certificate holder, and grantee programs and facilities that involve access to information classified under the AEA, as necessary. (d) Chairman of the NRC. In addition to the responsibilities in paragraph (h) of this section, the Chairman of the NRC: (1) Prescribes procedures for the portions of this rule that pertain to information under NRC programs classified under the AEA, other federal statutes, and executive orders. (2) Retains authority over access to information under NRC programs classified under the AEA, other federal statutes, and executive orders.

. This would be a one-time, first-year burden that includes an average of 30 minutes for a regulated entity to select an MFA solution that allows them to meet the requirements of the proposal without creating workflow disruptions or delays. This estimate would vary depending on how prevalent MFA is in the industry when and if the requirements of the NPRM are finalized. As a widely accepted information security practice, the Department believes that many large entities have already deployed MFA and the costs range from zero to only a few dollars per user. The low estimate would be 01 hours on average (assuming that many entities already have some form of MFA), and the high estimate would be 1.75 hours (assuming that few entities have MFA). At the loaded wage rate of an information security analyst, the total estimated cost would be \$327,903,966 [= 1,822,600 regulated entities × 1.5 hours × \$119.94], with a low estimated total of \$218,602,644 [= 1,822,600 regulated entities × 1 hour × \$119.94] and a high estimated total of \$382,554,627 [= 1,822,600 regulated entities × 1.75 hours × \$119.94]. The Department applies this cost in the first year only because minimal additional labor is needed to maintain this safeguard once it has been deployed. f. Costs Related to Network Segmentation The Department believes that most large regulated entities and many medium-sized regulated entities have segmented their information networks to some degree; however, additional actions may be needed to more fully protect ePHI as required under proposed 45 CFR 164.312(a)(2)(vi) . Further, small entities may not have been aware of the importance of segmenting

networks or taken steps to segment their networks. The Department estimates that each regulated entity would spend an average of 4.5 hours to set up network segmentation in the first year of compliance with a final rule (with a low estimate of 4 hours and a high estimate of 5 hours) at the hourly wage of an information security analyst. The Department further assumes that in the following years, the burden to maintain the segmented network would be minimal and incorporated into the maintenance requirements. The total first year estimated cost of the network segmentation requirement would be \$983,711,898 [= 1,822,600 regulated entities × 4.5 hours × \$119.94] with a low estimated total of \$874,410,576 [= 1,822,600 regulated entities × 4 hours × (printed page 999) \$119.94] and a high estimate of \$1,093,013,220 [= 1,822,600 regulated entities × 5 hours × \$119.94].

g. Cost Related to Disabling Ports and Removing Extraneous Software The Department believes that large regulated entities have already disabled unused network ports and removed extraneous software as part of existing configuration requirements. However, the Department believes that small and medium-sized regulated entities are less likely to have performed these actions and thus would incur a new burden to implement these aspects of configuration management proposed at

470. ·Risk Analyses vs. Gap Analyses·What is the difference?· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Apr. 2018), <https://www.hhs.gov/sites/default/files/cybersecurity-newsletter-april-2018.pdf> . Back to Citation 471. ·Joint Task Force, ·Guide for Conducting Risk Assessments,· NIST Special Publication 800-30, Revision 1, National Institute of Standards and Technology, U.S. Department of Commerce (Sept. 2012), <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-30r1.pdf> . Back to Citation 472. Id. at Appendix I; see also ·Reducing the Significant Risk of Known Exploited Vulnerabilities,· Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security (Nov. 3, 2021), https://www.cisa.gov/sites/default/files/publications/Reducing_the_Significant_Risk_of_Known_Exploited_Vulnerabilities_211103.pdf . Back to Citation 473. See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461, p. 16-22. Back to Citation 474. ·2016-2017 HIPAA Audits Industry Report,· supra note 121. Back to Citation 475. Id. Back to Citation 476. ·Press Release, ·HHS Office for Civil Rights Settles HIPAA Security Rule Failures for \$950,000,· U.S. Department of Health and Human Services (July 1, 2024), <https://prod-www.hhs.gov.cloud.hhs.gov/about/news/2024/07/01/hhs-office-civil-rights-settles-hipaa-security-rule-failures-950000.html> . Back to Citation 477. · See ·Montefiore Medical Center,· supra note 248. Back to Citation 478. · See ·Doctors' Management Services, Inc.,· supra note 246. Back to Citation 479. · See Letter from NCVHS Chair Jacki Monson (2023), supra note 123, Appendix p. 4-6. Back to Citation 480. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) . Back to Citation 481. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (1). Back to Citation 482. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (2). Back to Citation 483. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (3). Back to Citation 484. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (4). Back to Citation 485. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (5). Back to Citation 486. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (6). Back to Citation 487. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (7). Back to Citation 488. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (8). Back to Citation 489. · See NCVHS recommendation to test at multiple points in the life cycle of a system, including ·at every significant change throughout the life of the system[.]· Letter from NCVHS Chair Jacki Monson (2023), supra note 123, Appendix p. 6. Back to Citation 490. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461; ·Security Rule Guidance Material,· Office for Civil Rights, U.S. Department of Health and Human Services (Feb. 16, 2024),

MA.L2-3.7.4 · Media Inspection CMMC Assessment Guide · Level 2 | Version 2.13 151 from malicious code, and MA.L2 -3.7.4 extends this requirement to diagnostic and testing tools. Example You have recently been experiencing performance issues on one of your servers. After troubleshooting for much of the morning , the vendor has asked to install a utility that will collect more data from the server. The file is stored on the vendor-s FTP server. The support technician gives you the FTP site so you can anonymously download the utility file. You also ask him for a hash of the utility file. As you download the file to your local computer , you realize it is compressed. You unzip the file and perform a manual antivirus scan, which reports no issues [a]. To verify the utility file has not been altered, you run an application to see that the hash from the vendor matches.

Potential Assessment Considerations · Are media containing diagnostic and test programs (e.g., downloaded or copied utilities or tools from manufacturer, third -party, or in -house support

teams) checked for malicious code (e.g., using antivirus or antimalware scans) before the media are used on organizational systems [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.7.4

Shift the requirement to post award. Re-evaluate the program to reduce requirements to make it easier. Stay with only the DCMA DIBCAC performing assessments on the DIB. DoD Response: DoD considered many alternatives before deciding upon the current CMMC structure. To date, alternative methods of assessment have proven inadequate and necessitated the establishment of CMMC. The DoD determined the requirements for a CMMC Accreditation Body, and this accreditation body will administer the CMMC Ecosystem. DoD must enforce CMMC requirements uniformly across the DIB for all contractors and subcontractors who process, store, or transmit CUI. The value of information and the impact of its loss does not diminish when the information moves to contractors and subcontractors. The DoD notes with interest the commenter's reference to initiatives in a report to Congress describing the breadth of cybersecurity related initiatives within the Department. While the CMMC Program is an important initiative, it is by no means the Department's only effort to improve DIB cybersecurity. The CMMC Program addresses the adequate safeguarding of contractor owned information systems which process, store, or transmit FCI or CUI. Other DoD initiatives related to secure cloud or software development environments are beyond the scope of the CMMC Program. The DoD declined to accept the recommended alternative of relying exclusively on self-assessment with the potential to require a DIBCAC assessment for only a sampling of DoD contractors, which is essentially the status quo. Both GAO reporting and other DoD analysis have shown that the DIB has not consistently implemented the NIST SP 800-171 requirements needed to comply with DFARS clause 252.204-7012, notwithstanding DoD's stated objective in this clause is for compliance as soon as practical, but not later than December 31, 2017. The DoD declined to accept the risk associated with implementing CMMC as a post-award requirement. When contracts require contractors to process, store, or transmit CUI, DoD requires that they be compliant with DFARS clause 252.204-7012 and competent to adequately safeguard CUI from the beginning of the period of performance. DoD declined the recommendation to require primes to assume the cost of CMMC compliance for their subcontractors. The aggregated SPRS reporting and scoring is CUI. The DoD does not plan to make this information public at this time, as it may aid adversaries in coordinating their attacks. (printed page 83201) The Department declined to adopt the recommendation to allow DIB members to assist in designing the DoD's mechanism for assessing DIB compliance with DoD's contractual requirements. In developing the CMMC program, the DoD sought and considered DIB input.

From the NIST SP 800-172 Rev 3 Final Public Draft: to resist it, and is determined to maintain the level of interaction needed to execute its 204 objectives. C UI associated with critical programs or high value assets is at increased risk and requires additional protection because the APT is likely to target such information. The APT is dangerous to the national and economic security interests of the United States since organizations depend on systems^{7 7} The term 'system' is used to represent the people, processes, and technologies involved in the processing, storage, or transmission of CUI. of all types, including information technology (IT) systems, operational technology (OT) systems, and (3) Internet of Things (IoT) devices. The convergence of these types of systems and devices has brought forth a new class of systems known a

With regard to the comment's statement that records be retained from the time of manufacture, FDA does not agree. The record retention periods begin at the time the food is received and released. Under § 1.360(a) of this final rule, you must create the required records at the times you receive and release food, except to the extent that the information is contained in existing records. (Comment 132) One comment suggests that retaining records for 6 months after the product expiration date should be more than adequate for investigations for potential threats associated with the food. The comment indicates that expanding system capacity to accommodate much longer record retention is a major cost associated with implementing the proposed regulation and that FDA should either justify the value for longer record retention periods against the increased burden being placed on the industry or substantially decrease the number of records that must be retained for longer duration. (Response) As previously noted in response to comment number 129, FDA has considered various options and has chosen to require record retention based on criteria similar to the NIST definitions for perishable, semiperishable and long shelf-life food. FDA is convinced such an approach is the most efficient and effective because the food industry already is familiar with classification of foods into these three categories due to existing regulations and practices; and it will mitigate the problem raised by some comments of inadequate infrastructure for long term storage of records for the shorter shelf life foods. FDA notes that a traceback may not begin until well past the time the

food has been consumed, as explained in the response to the following comments. (Comment 133) A few comments contend that a shorter record retention time, such as 3 to 6 months, should be sufficient time for retention of records because any harmful effect directly related to a perishable food would be detected well within the life expectancy of the food. (Response) FDA does not agree that harmful effects directly relating to perishable foods always can be detected within the shelflife of the food. FDA has experienced some situations in which the health hazard was not immediately apparent, but only emerged several months after the food was consumed. Also, FDA recognizes the potential for serious adverse health consequences caused by novel contaminants or novel food sources for known contaminants. In such situations, it may take months to identify the source of contamination, or the contaminant itself.

- To provide a basis for testing tools to ensure they comply with SCAP 1.3 - To reduce the burden on SCAP 1.3 tool and content developers by clearly defining all SCAP 1.3 extensions in a single place

(Comment 118) Several comments state that the identity of the transporter is known to the shipper but is not typically known to the receiver. The comments assert that it is unreasonable to expect the receiver to have, seek, or maintain information on the identity and related contact information for the transporter that delivered the product, especially if multiple transporters may have been involved. The comments state (printed page 71601) that such information would be available from the shipper that arranged the transport. One comment states that it is not usual business practice for distributors to keep records about the transporter who delivers food. (Response) FDA believes that excluding a source from keeping records on the immediate previous source if that immediate previous source is a transporter would hinder a traceback investigation. The proposed and final rule require nontransporters to identify the name of the firm, address, telephone number and, if available, the fax number and e-mail address of the transporter who transported the food to and from them. See §§ 1.337(a)(6) and 1.345(a)(6) of this final rule. These provisions however, do not require the nontransporter to record transactions to which they were not a party, e.g., where multiple transporters are involved. I. Comments on Who is Required to Establish and Maintain Records for Tracing the Transportation of All Food? (Proposed § 1.351) (Comment 119) Several comments stated that foreign transporters are not included in the definition of foreign facilities and that the final rule should be applied to foreign transporters as it is to domestic transporters. (Response) FDA has excluded all foreign persons, except foreign persons who transport food in the United States, from all of the regulations in subpart J of this final rule. Therefore, foreign transporters are subject to the same requirements as domestic transporters when transporting food in the United States. (Comment 120) A number of comments noted that many nontransporters own trucks or other vehicles and transport food or feed as an incidental part of their operations. They express concern that they would be required to keep two sets of records, one as a nontransporter, and the other as a transporter. One comment recommends that the final rule be applicable to both private and for-hire transporters.

materials that are separated from edible food by a functional barrier. In other words, at a minimum, any materials that are separated from edible food by a functional barrier should be regarded as a type of outer packaging for which recordkeeping is not required. The comment states that FDA has long recognized the use of a functional barrier in determining what types of materials can be used in a packaging product. If a functional barrier (such as aluminum foil) is present in a packaging laminate, there is no expectation of migration of any material through the functional barrier. Therefore, the comment strongly requests that any materials on the exterior side of a functional barrier be excluded from the recordkeeping regulation. Because there is no expectation of migration of any material through a functional barrier, the likelihood that such materials could be used to adulterate food is extremely remote. One comment states the reference to packaging does not mandate recordkeeping by packaging suppliers or transporters. Indeed, the reference to packaging, in addition to food, indicates a distinction between the two terms in the view of the drafters. The law and Congressional intent would be satisfied by a food processor maintaining records identifying the source of the finished packaging for the food product. In the unlikely event that food packaging is the target of terrorists, records in the hands of food processors regarding their packaging suppliers will allow FDA to follow the history of the packaging and its components. The regulation as proposed by FDA extends far beyond what was intended by Congress. To follow Congressional intent, the comment states FDA needs to revise the proposed regulation to provide only that food processors have records identifying the suppliers of their packaging.

CIS Control 11 · Data Recovery Establish and maintain data recovery practices sufficient to restore in-scope enterprise assets to a pre-incident and trusted state. In the cybersecurity triad · Confidentiality, Integrity, and Availability (CIA) · the availability of data is, in some cases, more critical than its confidentiality. Enterprises need many types of data to make business decisions, and when that data is not available or is untrusted, then it could impact the enterprise. An easy example is weather information to a transportation enterprise. When attackers compromise assets, they make changes to configurations, add accounts, and often add software or scripts. These changes are not always easy to identify, as attackers might have corrupted or replaced trusted applications with malicious versions, or the changes might appear to be standard-looking account names. Configuration changes can include adding or changing registry entries, opening ports, turning off security services, deleting logs, or other malicious actions that make a system insecure. These actions do not have to be malicious; human error can cause each of these as well. Therefore, it is important to have an ability to have recent backups or mirrors to recover enterprise assets and data back to a known trusted state. There has been an exponential rise in ransomware over the last few years. It is not a new threat, though it has become more commercialized and organized as a reliable method for attackers to make money. If an attacker encrypts an enterprise's data and demands ransom for its restoration, having a recent backup to recover to a known, trusted state can be helpful. However, as ransomware has evolved, it has also become an extortion technique, where data is exfiltrated before being encrypted, and the attacker asks for payment to restore the enterprise's data, as well as to keep it from being sold or publicized. In this case, restoration would only solve the issue of restoring systems to a trusted state and continuing operations. Leveraging the guidance within the CIS Controls will help reduce the risk of ransomware through improved cyber hygiene, as attackers usually use older or basic exploits on insecure systems.

The cost estimates and assumptions referenced by the commenters pertain to CMMC 1.0 and are not reflective of the changes in CMMC, though public comment feedback has been incorporated into the cost estimation process for the CMMC Program where appropriate. The Department limited estimates for CMMC to those costs associated with preparing for, attaining, and publishing results of: (a) CMMC compliance via self-assessment for CMMC Levels 1 and 2, and (b) certification at CMMC Level 2 through a C3PAO and Level 3 through the DoD. Costs for companies to implement information security protections to comply with the existing FAR subpart 4.19 to achieve CMMC Level 1, and DFARS subpart 204.73 to achieve CMMC Level 2, are distinct from costs associated with CMMC assessment processes to verify and attest to the corresponding implementation of existing rules. Cost estimates were developed for companies to implement security requirements for CMMC Level 3. CMMC Level 3 security requirements are defined in table 1 to § 170.14(c)(4) CMMC Level 3 Requirements. For the vast majority of the DIB, CMMC does not levy additional information security protection requirements but is designed to provide increased assurance that defense contractors are contract compliant and can adequately protect FCI and CUI at a level commensurate with risk, accounting for information flow down to its subcontractors in a multi-tier supply chain. There is no recognized duplication of assessments for small companies that support many primes, because once assessed, an organization need only provide evidence of compliance or certification to prospective primes in order to satisfy the CMMC requirement in a solicitation. When information system or network boundaries differ, an additional assessment may apply. b. CMMC Cost Burden Comment: Several commenters suggested that costs were underestimated, particularly for small businesses who were perceived to be at risk of decreased participation in the (printed page 89074) marketplace due to the cost prohibitive nature of the CMMC requirement. Multiple commenters requested additional strategies to mitigate costs, including the promotion of new technologies. Response: CMMC Levels 1 and 2, which represent the majority of the anticipated requirements, does not levy any additional information security protection requirements. To address assessment cost concerns, CMMC eliminates the third-party assessment requirement at CMMC Level 1 and permits self-assessment for certain contracts containing a CMMC Level 2 requirement. The DoD Office of Small Business Programs, available at <https://business.defense.gov/>, has informational resources that may help defray cybersecurity implementation costs by helping organizations stay up-to-date with the latest cybersecurity compliance and policy best practices. c. CMMC Cost Effectiveness and Alternatives Comment:

· Because the presence of labels do not preclude reading of the labels of any PDU, the labels themselves may need be protected against being read by unauthorized readers (label secrecy protection). This could be provided through the use of encryption or through physical protection of the media. · The PDU's data portion, which is associated with the label, may also need to be

protected against integrity and secrecy attacks. This could again be provided through use of encryption or through physical protection of the media. | 1 . Introduction | 2 |
 |-----|-----| | 2. Access Control
 Requirements | 2 | | 3. Labelling Requirements | 2 | | 4. The Labelling Problem | 3 | | 5. Labelling
 Facilities | 4 | | 6. Mechanisms to Support Labelling (N)-Facilities | 5 | | 6.1 Supporting a
 fixed-(set-)labelling (N)-facility | 8 | | 6.1.1 Using a fixed-(set-)labelling (N-I)-facility | 8 |
 | 6.1.2 Using a variable- or multi-(set-)labelling (N- 1)-facility | 9 | | 6.2 Supporting a
 variable- or multi- (set-)labelling (N)-facility | 9 | | 6.2.1 Using a fixed-(set-)labelling
 (N-I)-facility | 9 | | 6.2.2 Using a variable- or multi-(set-)labelling (N-I)-facility | 11 | | 7.
 Summary of (N)-Facility Support | 11 | | 8. Support of a Fixed Label-Set Association | 13 | | 9.
 Support of Variable or Multiple Label-Set Associations | 14 | | 9.1 Support by variable- and multi-
 set-labelling facilities | 14 | | 9.2 Support by single-labelling facilities | 14 | | 10.

The use of health IT, including EHRs (certified or otherwise), has led to enormous advancements in the fields of medicine and public health, not only improving outcomes for individuals, but also assisting in addressing the social, economic, and environmental factors that affect health on an individual and community level. [113] And the electronic exchange of health information, spurred by HIPAA, the HITECH Act, and the 21st Century Cures Act (·Cures Act·), [114] has enabled regulated entities and others to more quickly and efficiently share individuals' health information, increasing the quality and efficiency of health care, increasing patient engagement, and reducing administrative burden. [115] However, the widespread use of health IT systems makes it even more critical for regulated entities, regardless of their size or location, to fully assess the risks and vulnerabilities to ePHI and their information systems and implement strong security measures to address those risks and vulnerabilities. Experts repeatedly have expressed concern regarding the state of cybersecurity in the health care industry. [116] For example, in a 2017 report to Congress, experts convened by the Department pronounced, ·Now more than ever, all health care delivery organizations [. . .] have a greater responsibility to secure their systems, medical devices, and patient data.· [117] This responsibility has only increased as the delivery of health care and the exchange of PHI have increasingly shifted to cyberspace. Despite advancements in technology, including health IT, the core requirements of the Security Rule remain relevant and applicable today. In fact, they serve as a foundation for more recently promulgated cybersecurity guidelines, best practices, processes, and procedures. Security management, regular monitoring and review of information system activity, information access management, security awareness and training, contingency planning, encryption, and authentication all continue to be represented in the most well-known cybersecurity frameworks, including the NIST's Cybersecurity Framework, [118] the HHS 405(d) Program's ·Health Industry Cybersecurity Practices: Managing (printed page 907) Threats and Protecting Patients,· [119] and the Department's CPGs. [120] While these concepts remain highly relevant and applicable, the Department has concerns regarding the sufficiency of the security measures implemented by regulated entities. OCR's experience investigating allegations of Security Rule violations, reports received by OCR of breaches of unsecured PHI, and the results of the audits conducted by OCR in 2016-2017 demonstrate that regulated entities are not consistently complying with the Security Rule's requirements. [121]

Multiple commenters commented on the cost impact of CMMC to small businesses, suggesting that the cost to become and remain compliant is too high. Several commenters added that small businesses limited by finances won't be able to compete, which could be detrimental to the supply chain and efforts to meet national defense goals, and that the rule fails to provide any consideration for the future loss of technology acquisition should small businesses be inadvertently precluded from participation. Other commenters suggested that the impact of CMMC will be a profound and significant obstacle to businesses due to their lack of resources as compared to their large business competitors, adding that the requirement to have the same measures in place for any company, regardless of size, incurs a higher percentage of indirect cost for small businesses. Multiple commenters remarked on the limited or lack of options for a small business to recover costs. Response: The estimated costs attributed to this rule do not include the costs associated with compliance with existing cybersecurity requirements under FAR clause 52.204-21 or associated with implementing NIST SP 800-171 requirements in accordance with DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting. To the extent that defense contractors or subcontractors have already been awarded DoD contracts or subcontracts that include these clauses, and process, store, or transmit FCI or CUI in support of the performance of those

contracts, costs for implementing those cybersecurity requirements should have already been incurred and are not attributed to this rule. Those costs are distinct from costs associated with undergoing a CMMC assessment to verify implementation of those security requirements. The CMMC Program does not levy additional information security protection requirements for CMMC Levels 1 and 2. The value of DoD's sensitive information (and impact of its loss to the Department) does not diminish when it moves to contractors prime or sub, large or small. A Regulatory Flexibility Analysis was conducted. In comparison to CMMC 1.0, DoD has now eliminated the requirement for organizations to hire a third-party assessment organization to comply with CMMC Level 1. The CMMC Program requirements further address cost concerns by permitting self-assessment at Level 1 and at Level 2 for some contracts that are not designated to require the added assurance of C3PAO assessment. In addition, resources available through the DoD Office of Small Business Programs (OSBP) may help defray cybersecurity costs by helping companies stay up to date with the latest cybersecurity policies and best practices. The OSBP also partners with the NIST and its Manufacturing Extension Partnership (MEP) programs (<https://www.nist.gov/mep>), which operate across the U.S. to provide resource and funding assistance options.

The OSA is responsible for determining its CMMC Assessment Scope and its relationship to security domains. Assets are out-of-scope when they are physically or logically separated from the assessment scope. Contractor Risk Managed Assets are only applicable within the OSA's assessment scope. Table 3 to § 170.19(c)(1) is used to identify the asset categories within the assessment scope and the associated requirements for each asset category. Contractor's risk-based security policies, procedures, and practices are not used to define the scope of the assessment, they are descriptive of the types of documents an assessor will use to meet the CMMC assessment requirements. It is beyond the scope of the CMMC rule to provide a detailed explanation of the usage of risk-based terminology when implementing or assessing CMMC requirements. DoD declines to speculate and clarify the relationship between any NIST SP 800-171 R2 definitions and any pending NIST SP 800-171 Revision 3 definitions. The DoD has defined the effort allowed during a limited check in table 1 to 170.19(c)(1). A limited check may require submission of evidence. The DoD cannot anticipate how an OSC will scope its CMMC Level 3 assessment with respect to its CMMC Level 2 environment. As specified in table 5 to § 170.19(d)(1), Level 2 Contractor Risk Managed Assets are categorized as CUI Assets at Level 3. The rule has been updated to clarify that ESPs do not require a Level 3 certification unless they process, store, or transmit CUI in the performance of a contract with a CMMC Level 3 requirement. As stated in table 1 to § 170.19(c)(1), CRMA assets must be prepared to be assessed against CMMC requirements. The SSP must provide sufficient documentation describing how security requirements are met to allow the assessor to follow the instruction in table 1 to not assess against other requirements. The assessor will then decide if a limited spot check is warranted. The results of the limited spot check can result in a requirement being scored as NOT MET. The rule does not create two classes of Contractor Risk Managed Assets as one commenter asserts. Contractor Risk Managed Assets are only those assets that are owned by the OSC and within the assessment scope. ESP assets are subject to the ESP requirements of the rule. All assets within the OSA defined assessment boundary have access to CUI and can process, store, or transmit CUI, and are therefore subject to DFARS clause 252.204-7012 and required to meet NIST SP 800-171 requirements. This is the authority for including CRMAs within CMMC assessments. For Level 2, DoD has decided to assume some risk and lessen the assurance burden for a class of these assets called Contractor Risk Managed Assets, as specified in table 3 to § 170.19(c)(1). DoD does not assume this risk at Level 3. Contractor Risk Managed Assets are subject to assessment against all CMMC requirements as specified in table 5 to § 170.19(d)(1).

Control OA-3: In indirect verification architecture, the user authenticates to a Verifier that is not the Relying Party, after which the Verifier provides the Relying Party with an assertion that the user's identity has been verified. As described in Section 9 of NIST SP 800-63 [2], which provides detailed requirements for use of assertions, some assertion mechanisms can provide e-authentication level 4 assurance to the Relying Party (e.g., Kerberos), and such mechanisms are preferred and should be employed whenever possible, if the indirect verification architecture is used. 15 The Kerberos Network Authentication Protocol [16] is commonly used to implement indirect verification, and it can be implemented in such a way that it provides e-authentication level 4 assurance to the Relying Party. The assertions created by the Verifier in Kerberos are called Kerberos tickets, and they include symmetric session keys that allow the Relying Party to perform a strong cryptographic authentication of the Claimant. The overall authentication process must ensure that the Claimant uses a PIV credential to authenticate to the Verifier before access is granted by the Relying Party. This

requirement is satisfied if the Verifier is configured to only accept PIV authentication. Security Assertion Markup Language (SAML) bearer assertions [17] are also commonly used to implement indirect verification. Unlike Kerberos, with bearer assertions the Claimant authenticates to the Relying Party by simply providing a copy of the assertion that it got from the Verifier. So, unlike Kerberos, an attacker could defeat the authentication mechanism by 14 See Section 6.2.3.1 of FIPS 201-2 [5] for an example of PKI-based authentication using the PIV Authentication certificate.

(6) Any CUI training requirements the contractor must adhere to in order to comply with 32 CFR 2002.30 ; and (7) Any CUI incident reporting instructions required by the agency, to include the agency website or single point of contact. PART 12-ACQUISITION OF COMMERCIAL PRODUCTS AND COMMERCIAL SERVICES 25. Amend section 12.202 by adding paragraph (f) to read as follows: 12.202 Market research and description of agency need. * * * * (f) Requirements documents for acquisitions involving controlled unclassified information (CUI) shall: (1) Comply with 32 CFR part 2002 ; and (2) Incorporate all applicable handling and compliance instructions included in the SF XXX, Controlled Unclassified Information (CUI) Requirements (see 4.403 and 11.002(i)). 26. Amend section 12.301 by revising paragraph (d)(5) to read as follows: 12.301 Solicitation provisions and contract clauses for the acquisition of commercial products and commercial services. * * * * (d) * * * (5) Insert the clause at 52.204-21, Basic Safeguarding of Covered Contractor Information Systems, in solicitations and contracts (except solicitations and contracts solely for the acquisition of COTS items), as prescribed in 4.404-3. * * * * PART 15-CONTRACTING BY NEGOTIATION 15.407-1 [Amended] 27. Amend section 15.407-1 by removing from the introductory text of paragraph (f) the phrase 'improper disclosure.' and adding 'improper disclosure such as requirements for controlled unclassified information or classified information.' in its place. 28. Amend section 15.604 by: a. Removing from paragraph (a) introductory text the phrase 'proprietary information' and adding 'contractor proprietary business information' in its place; and b. Revising paragraph (a)(7). The revision reads as follows: 15.604 Agency points of contact. * * * * (a) * * * (7) Instructions for identifying and marking contractor proprietary business information so that it is protected and administrative markings conform to 15.609. * * * * 15.606-2 [Amended] 29. Amend section 15.606-2 by removing from paragraph (a) introductory text the phrase 'the legend' and adding 'the administrative marking' in its place. 30. Amend section 15.609 by: a. Removing from paragraphs (a) and (b) the phrase 'the following legend' and adding the phrase 'the following administrative marking' in its place; b. Revising paragraph (c); c. Removing from paragraph (d) the phrase 'clearly mark' and adding the phrase 'clearly administratively mark' in its place; d. Removing from paragraph (e) the phrase 'and privileged or confidential information to the Government' and adding 'privileged or confidential information, or other controlled unclassified information' in its place; e. Revising paragraph (f); and f. Removing from paragraphs (g), (h) introductory text and (h)(1) the term 'legend' and adding 'administrative marking' in its place. The revisions read as follows: 15.609 Limited use of data. * * * * *

s [SecureByDesign] applied to consumer-grade routers should guide manufacturers to minimize the number of interfaces, both logical and physical and general functionality provided by the router device. The primary functionality of the home router is to provide access to the Internet for devices within the home. Extraneous functions should not be included in this component. For example, configuration may be better managed by another product component (e.g., mobile application). This is not to suggest a product composed of only a router device is necessarily less secure than those that can offload functions to other components.. - Robust network onboarding support from consumer-grade router products. Cybersecurity when provisioning new devices to the network connected to a consumergrade router can go beyond a single password. When a router product is composed of components such as mobile applications or backends, those components can be used as part of a more robust onboarding mechanism. For example, when a device is attempting to connect to the router device with (or without) the password, the mobile application can notify the owner and ask for explicit approval for the device to onboard. Though reliability needs to be considered to ensure individuals can always access and use their routers, onboarding mechanisms for consumer-grade routers that give individuals more access control over their networks is generally beneficial. For additional recommendations on consumer IoT onboarding and device credentialing see Trusted Internet of Things (IoT) Device Network-Layer Onboarding and Lifecycle Management: Enhancing Internet Protocol-Based IoT Device and Network [SP1800-36].

J. Comments on What Information is Required in the Transportation Records? (Proposed §.1.352)

(Comment 122) Several comments recommend that FDA exempt transporters from all recordkeeping elements except the immediate source and immediate subsequent recipient. They note that the cost of complying is not proportional to the risk. (Response) FDA disagrees with this comment. FDA, however, has taken steps to minimize the burden on transporters by including five alternatives to meet their obligations to establish and maintain records under this final rule. FDA notes that transporters also are subject to the records access requirements in §§ 1.361 and 1.363 of this final rule. This will ensure that FDA has access to all applicable records that will enable FDA to perform a tracing investigation quickly and effectively. Additionally, to ensure there are no gaps in transporter coverage in a traceback investigation, the final rule applies to both interstate and intrastate transporters of food. (Comment 123) Comments arguing for exemption of transporters state that it is difficult or impossible for the crew of the transporter to open each container of food, contaminate it, repackage it, replace seals, and arrive on time without leaving any trace of their intervention. Other comments suggest that a known and trustworthy transport company will not risk their business by doing something of this nature. (Response) FDA disagrees that the transportation process is any less vulnerable to attacks on the food supply than any other part of the food industry. FDA believes that recordkeeping requirements are necessary for transporters, but, as discussed previously, it has taken steps to minimize the burden on transporters. (Comment 124) A number of comments state that the transporter has no access to detailed information about the shipment and is dependent on the information listed on the bill of lading provided by the shipper. Therefore, the information required of transporters should be limited to the information on the bill of lading. One comment states that a bulk shipper, for example, has a 5,000 gal shipment of orange juice and has access to only this information, and detailed descriptive information such as brand names, specific variety, and package types are not applicable to bulk loads. Several comments state that transporters are frequently provided with preloaded and/or sealed vehicles for transport, and the transporter does not have knowledge of the contents (printed page 71602) other than what is on the bill of lading prepared by the shipper. They argue that they cannot access the sealed cargo to obtain specific information to confirm or supplement the bill of lading information. Similarly, other comments advise that they cannot verify bill of lading information for food contained in shrink-wrapped pallets. These comments believe that the carriers responsibility should be limited to the description provided by the shipper.

IT systems used to provide these functions face a variety of threats. If IT systems are not selected, configured and managed using security practices commensurate with the importance of the services they provide and the sensitivity of the data they handle, a security compromise could carry consequences for the integrity of the election and the confidentiality of sensitive voter information. Failure to adequately address threats to these systems could prevent voters from casting ballots, expose individuals to identity fraud, or even compromise the results of an election. This document follows NISTIR 7551, A Threat Analysis on UOCAVA Voting Systems , which documents the threats to UOCAVA voting systems using electronic technologies for all aspects of the remote voting process. While NISTIR 7551 discusses high-level security controls capable of mitigating threats, the focus of that report was identifying technologies and associated risks. This document complements NIST 7551 by providing security best practices to help jurisdictions create UOCAVA voting systems based on security practices used in other IT applications. There are many different ways to support UOCAVA voters, and each jurisdiction must put together its own system for such support. This document covers some common parts of UOCAVA system architectures, and shows how to secure those parts against both normal and extraordinary threats. The two components that are covered in most detail are Internet-based or Internet-assisted delivery of blank ballots and voter registration.

(8) Access to SCI, SAP, FRD, and RD information is a determination made by the granting authority by the applicable USG granting authority for each category of information. (b) Investigative requirements. E.O. 13467 , as amended, Reforming Processes Related to Suitability for Government Employment, Fitness for Contractor Employees, and Eligibility for Access to Classified National Security Information, designates the Security and Suitability Executive Agents responsible for establishing the standards for investigative requirements that apply to contractors. (1) Investigative tiers. The standards established in accordance with E.O. 13467 , as amended, designate specific investigative tiers that are acceptable for access to classified information. An investigative tier is for positions designated as moderate risk, non-critical sensitive, and allow access to information classified at the L, CONFIDENTIAL, and SECRET levels. Another investigative tier is for positions designated as high risk, critical sensitive, special sensitive, and allow

access to information classified at the Q, TOP SECRET, and SCI levels. (2) Investigative coverage.

(i) Automated sources. Investigative providers will use automation whenever possible to collect, verify, corroborate, or discover information about an individual, as documented on the request for investigation or developed from other sources, i.e., automated record checks and inquiries. (ii) Interviews. Interviews, if required, will cover areas of adjudicative concern. (iii) Information Covered in Previous Investigations. Information validated in a prior investigation, the results of which are not expected to change (e.g., verification of education degree), will not be repeated as part of subsequent investigations. (3) Polygraph. Agencies with policies authorizing the use of the polygraph for purposes of determining eligibility for access to classified information may require polygraph examinations when necessary. If adjudicatively relevant information arises during the investigation or the polygraph examination, the investigation may be expanded to resolve the adjudicative concerns. (4) Financial disclosure. When a GCA requires that a contractor employee complete a financial disclosure form, the contractor will ensure that the employee has the opportunity to complete and submit the form in accordance with the Privacy Act of 1974, as amended, and other applicable provisions of law. (5) Reinvestigation and Continuous Evaluation. Contractor employees (printed page 83329) determined eligible for access to classified information will follow CSA guidance to complete reinvestigation and continuous evaluation or continuous vetting requirements. The contractor will validate that the employee requires continued eligibility for access to classified information before initiating the reinvestigation. (c) Verification of U.S. citizenship.

Two commentors recommended the elimination of separate assessments when the FCI and CUI environments are the same. One of these comments requested clarification regarding the scenario of an OSC having one assessment scope environment for both FCI and CUI that meets Level 2 requirements. Response: CMMC Level 2 is required when CUI will be processed, stored, or transmitted on contractor information systems. Successful completion of a CMMC Level 2 self-assessment or CMMC Level 2 certification assessment will suffice to meet the CMMC Level 1 requirement for FCI if/when the scope is identical. The CMMC Level 2 Scoping Guide reflects this language. e. Recommendations and Scenarios Comment: One comment recommended removing CMMC Level 2 self-assessment, changing the CUI Program, or creating a new type of CUI to distinguish between CMMC Level 2 self-assessment and CMMC Level 2 Certification. Another comment noted that the requirements for CMMC Level 2 certification assessment are almost identical to requirements for CMMC Level 2 self-assessment. One comment expressed concern that DoD's designation of CMMC Level 2 self- (printed page 83116) assessment and certification assessment runs contrary to FCI (FAR requirements) and the CUI Program. One comment asked if the designation of information as FCI or CUI changes the scope of CMMC. One comment asked for clarification on which contracts will have sensitive unclassified DoD information but will not require CMMC assessment. One comment recommended removing the option for CMMC Level 2 self-assessments to reduce complexity. One comment posed multiple questions about what DoD will do if contracting officers assign CMMC Level 2 or CMMC Level 3 Certification requirements at a rate substantially higher than projected. Response: The DoD CIO looked at CUI from a risk-based perspective and determined that different approaches to assessments could be implemented to address risk and help lower the burden for the DIB. The security requirements for a CMMC Level 2 self-assessment and a CMMC Level 2 certification assessment are the same, the only difference in these assessments is whether it is performed by the OSA or by an independent C3PAO. The decision to rely upon self-assessment in lieu of certification assessment is a Government risk-based decision based upon the nature of the effort to be performed and CUI to be shared. The size of the company with access to the CUI is not a basis for this determination. The value of information (and impact of its loss) does not diminish when the information moves to contractors of smaller size. The DoD declines to modify the rule to include its internal decision process.

- f The person or process identified as sending the transaction is actually the originator (nonrepudiation) - f The person or process receiving the transaction is the intended recipient (identification and authentication) - f Data integrity has not been compromised (integrity). 10 This section on PKI is drawn extensively from NIST SP 800-32, Introduction to Public Key Technology and the Federal PKI and NIST SP 800-25, Federal Agency Use of Public Key Technology for Digital Signatures and Authentication. - f Key Recovery -organizations must be able to recover data that the employee has encrypted, which can only be done by recovering the encryption key when the key is unavailable. 11 - f Privilege/Authorization -certificates can be used to vouch for a user's identity and also specify privileges the user has been granted.

Under the proposed implementation specification for network ports at proposed 45 CFR 164.312(c)(2)(iv), a regulated entity would be required to disable network ports in accordance with the regulated entity's risk analysis. [758] Successful ransomware deployment often depends on the exploitation of technical vulnerabilities such as unsecured ports. [759] The proposal to require network ports to be disabled in accordance with the risk analysis would reduce exploitable vulnerabilities. [760] Lastly, the proposed implementation specification for maintenance at proposed 45 CFR 164.312(c)(2)(v) would expressly require a regulated entity to review and test the effectiveness of the technical controls required by the other implementation specifications associated with the standard for configuration management at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. e. Section 164.312(d)(1) Standard: Audit Trail and System Log Controls Audit controls are crucial technical safeguards that are useful for recording and examining activity in electronic information systems, especially when determining whether a security violation occurred. [761] A regulated entity must consider its risk analysis and organizational factors, such as current technical infrastructure, hardware, and software security capabilities, to determine reasonable and appropriate audit controls. [762] However, based on OCR's enforcement experience, we believe that regulated entities' understanding of and compliance with this standard could be improved by providing more specificity. Accordingly, the Department proposes to redesignate the standard for audit controls at 45 CFR 164.312(b) as proposed 45 CFR 164.312(d)(1), rename it as the standard for audit trail and system log controls, and to add a paragraph heading to clarify the organization of the regulatory text. We also propose to modify it to require a regulated entity to deploy either or both technology assets and technical controls that record and identify activity in the regulated entity's relevant electronic information systems. The proposal would replace procedural mechanisms with technical controls, to match the general focus on technical controls in 45 CFR 164.312 and would recognize that a regulated entity may be able to meet the requirements of the standard by deploying either or both technology assets (e.g.,

(i) The Treaties provide a comprehensive framework for exports and transfers to the UK or AUS of certain classified and unclassified defense articles without a license or other written authorization. (ii) The ITAR part 126, supplement no. 1 identifies those defense articles and services that are not eligible for export via treaty exemptions. (iii) This exemption applies to contractors registered with the DDTC and eligible to export defense articles. (2) Defense articles. Defense articles fall under the scope of the Treaties when they are in support of: (i) U.S. and UK or U.S. and AUS combined military or counter-terrorism operations. (ii) U.S. and UK or U.S. and AUS cooperative security and defense research, development, production, and support programs. (iii) Mutually agreed specific security and defense projects where the government of the UK or AUS is the end-user. (iv) USG end-use. (3) Marking requirements. Contractors are required to mark defense articles that fall under the scope of the treaty prior to transferring from the U.S. to the UK in accordance with the provisions of this paragraph. All other standard classification marking in accordance with § 117.14 also apply. When defense articles are returned from the UK or AUS to the United States, any defense articles marked as RESTRICTED in the manner shown in Table 4 purely for the purposes of the treaties will be considered to be unclassified and such marking will be removed. Table 3 to Paragraph (i)(3) Classified U.S. Defense Article Markings UNCLASSIFIED: CLASSIFICATION MARKINGS FOR ILLUSTRATION PURPOSES ONLY Treaty with: Marking Example (for SECRET classified defense articles) Government of UK //CLASSIFICATION LEVEL USML/REL GBR AND USA TREATY COMMUNITY// //SECRET USML//REL GBR AND USA TREATY COMMUNITY// Government of AUS //CLASSIFICATION LEVEL USML/REL AUS AND USA TREATY COMMUNITY// //SECRET USML//REL AUS AND USA TREATY COMMUNITY// Table 4 to Paragraph (i)(3) Unclassified U.S. Defense Article Markings UNCLASSIFIED: CLASSIFICATION MARKINGS FOR ILLUSTRATION PURPOSES ONLY Treaty with: Marking Government of UK //RESTRICTED-USML//REL GBR AND USA TREATY COMMUNITY// Government of AUS //RESTRICTED-USML//REL AUS AND USA TREATY COMMUNITY// (4) Notice. A notice will be included (e.g., as part of the bill of lading) whenever defense articles are exported in accordance with the provisions of these treaties and the ITAR. (printed page 83358) Table 5 to Paragraph (i)(4) Notice Text for Exported Defense Articles Notice text

(B) Urgently needed means the information has a particular value that will be lost if not disseminated quickly, such as a breaking story of general public interest. Information of historical interest only, or information sought for litigation or commercial activities, would not qualify as urgently needed, nor would a news media publication or broadcast deadline unrelated to the news-breaking nature of the information. The burden of demonstrating that the requested information has a

particular value that will be lost if not disseminated quickly is on the requester. (ii) A demonstration of compelling need means a statement certified to be true and correct to the best of the requester's knowledge. This statement must accompany the request in order to be considered and responded to within the 10 calendar days required for decisions on expedited access. (2) Imminent loss of due process rights. Expedited processing shall also be granted to a requester if loss of substantial due process rights is imminent. A demonstration of imminent loss of substantial due process rights by the requester shall include a description of the due process rights that would be lost and a statement certified to be true and correct to the best of the requester's knowledge. This statement must accompany the request in order to be considered and responded to within the 10 calendar days required for decisions on expedited access. If the DoD Component decides to expedite the request for this reason, the request may be processed in the expedited track behind those requests qualifying for compelling need. (d) Consultation and referrals. The DoD Component shall take appropriate action as described in § 286.4(h)(2) when the record is not under its release authority because it requires consultation with another DoD Component or non-DoD agency, because the record was not originated by the Component, or because the record is not in the Component's system of records but is likely to be held by another DoD Component or non-DoD agency. The following actions are necessary when the record was originated by a non-Government source: (1) When a request is received for a record that arguably contains information exempt from release under Exemption 4, the provisions of E.O. 12600 apply. (i) When a FOIA request is received for records that may contain confidential commercial information (e.g., government contracts), the submitter shall be notified promptly of that request and afforded reasonable time (e.g., 20 calendar days) to present any objections concerning release. This practice of giving submitter notice is required by E.O. 12600

payment fraud, identity theft, credit card fraud) are collected and reported to various government and private entities. However, data that describe the economic impact of cybersecurity incidents more fully and completely, either at the firm or sector level, are not readily available. Not only are losses difficult to quantify with today's tools, but it appears to be difficult to assess in economic terms the return on investments achieved via security measures. Measures of business and consumer investment in security-related activities lack a common reporting entity or information aggregating mechanism. The availability of authoritative, aggregated data on cybersecurity investments and losses from cyber incidents might yield a quantitative picture of the economic impact of cyber intrusions and attacks. Such data would enable industry and the government to evaluate the severity of cybersecurity threats and emerging trends and to make informed decisions about the trade-offs of different cybersecurity strategies and investment options. We seek comment on the following questions: How should a data gathering and analysis system (or systems) be fashioned to facilitate the collection of well-defined, consistent metrics to measure the financial impact of cybersecurity incidents and investments in cybersecurity protection? What would be the implementation challenges? Are there adequate incentives for businesses to provide information about security breaches, data security losses, and cybersecurity investments? It would be beneficial from a national perspective to have a greater understanding of the financial costs and benefits of different cybersecurity practices. Does the private sector, however, lack incentives to share information at the firm level? What are reasonable means to acquire the data necessary for greater understanding? At what level of granularity should data be collected and analyzed? What would be the appropriate entity to perform collection and analysis of the data? Aside from assessing the known costs of cyber intrusions and attacks and of cybersecurity measures, what other data would be helpful to better understand the question of whether at the firm, sector and national levels enough is being done to adequately protect the nation's information and communications systems? Can the opportunity costs associated with inadequate security be estimated in some way? 2. Raising Awareness

AT.L2-3.2.3 · Insider Threat Awareness CMMC Assessment Guide · Level 2 | Version 2.13 71 FURTHER DISCUSSION An insider threat is the threat that an insider will use their authorized access, wittingly or unwittingly, to do harm. Insider threat security awareness training focuses on recognizing employee behaviors and characteristics that might be indicators of an insider threat and the guidelines and procedures to handle and report it. Training for managers will provide guidance on observing team members to identify all potential threat indicators, while training for general employees will provide guidance for focusing on a smaller number of indicators. Employee behaviors will vary depending on roles, team membership, and associated information needs. The person responsible for specifying insider threat indicators must be cognizant of these factors.

Because of this, organizations may choose to tailor the training for specific roles. This requirement does not require separate training regarding insider threat. Organizations may choose to integrate these topics into their standard security awareness training programs. Example You are responsible for training all employees on the awareness of high-risk behaviors that can indicate a potential insider threat [b]. You educate yourself on the latest research on insider threat indicators by reviewing a number of law enforcement bulletins [a]. You then add the following example to the training package: A baseline of normal behavior for work schedules has been created. One employee's normal work schedule is 8:00 AM-5:00 PM, but another employee noticed that the employee has been working until 9:00 PM every day even though no projects requiring additional hours have been assigned [b]. The observing employee reports the abnormal work schedule using the established reporting guidelines. Potential Assessment Considerations · Do training materials include potential indicators associated with insider threats (e.g., repeated security violations, unusual work hours, unexpected significant transfers of data, suspicious contacts, concerning behaviors outside the workplace) [a,b]? · Do training materials include methods of reporting potential indicators of insider threats to management or responsible security personnel [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.2.3

, Controlled Unclassified Information, in Federal solicitations and contracts. The objective of the rule is to implement uniform, Governmentwide policies and procedures for Federal agencies and contractors regarding handling of CUI. Since CUI requires protection regardless of dollar value or commerciality of the product or service, this rule will apply to contracts at or below the SAT and to commercial products and commercial services. The rule does not apply to contracts that are solely for the acquisition of COTS items. IV. Expected Impact of the Rule A. General Compliance Requirements Under the terms of this proposed rule, contractors will be required to safeguard CUI that the Government identifies in the standard form (SF) XXX, Controlled Unclassified Information (CUI) Requirements, and ensure handling consistent with 32 CFR part 2002 . This includes CUI that the agency provides to the contractor, or CUI that the contractor collects, develops, receives, transmits, uses, handles, or stores in performance of the contract. CUI is defined at FAR 2.101 as information that the Government creates or possesses, or that an entity creates or possesses for or on behalf of the Government, that a law, regulation, or Governmentwide policy requires or permits an agency to handle using safeguarding or dissemination controls. The contractor shall permit access to CUI only as described in the SF XXX. A contractor will need to review the SF XXX to determine what information under the contract is considered CUI and how to properly safeguard the CUI. If the contractor intends to flow CUI down to a subcontractor, then the contractor will also be required to prepare an SF XXX and distribute it to the subcontractor to ensure the subcontractor properly safeguards CUI. Any contractor or subcontractor employee that handles CUI will be required to complete training on safeguarding CUI, as specified on the SF XXX. Identification of CUI on the SF XXX triggers compliance requirements as specified in the new contract clause at FAR 52.204-XX, Controlled Unclassified Information, e.g., security requirements in NIST SP 800-171, Revision 2, or controls in NIST SP 800-53 depending on the type of information systems that process, store, or transmit CUI. The compliance requirements are discussed in more detail in section IV.C. of this preamble and will vary depending on the organizational Index Grouping and category of CUI being handled under the contract and how the information is being collected, developed, received, transmitted, used, handled, or stored. Prime contractors that flow down CUI to subcontractors will also be required to flow down the compliance requirements of the clause at FAR 52.204-XX; a requirement that applies at all subcontract tiers. The new clause at FAR 52.204-YY also flows down to subcontracts.

Responses per Respondent: Approximately 5.57. Annual Responses: 3,036. Average Burden per Response: Approximately 3 hours. Annual Burden Hours: 9,108. Reporting Frequency: On occasion. Needs and Uses: DFARS 204.404-70(a) prescribes use of DFARS Clause 252.204-7000, Disclosure of Information, in contracts that require the contractor to access or generate unclassified information that may be sensitive and inappropriate for release to the public. The clause requires the contractor to obtain approval of the contracting officer before release of any unclassified contract-related information outside the contractor's organization, unless the information is already in the public domain. In requesting this approval, the contractor must identify the specific information to be released, the medium to be used, and the purpose for the release. Upon receipt of a contractor's request, the Government reviews the information provided by the contractor to determine if it is sensitive or otherwise inappropriate for release for the stated purpose. Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. [FR Doc.

3.5.6 Record Retention Information Type... 3.5.6 Record Retention Information Type Records Retention involves the operations surrounding the management of the official documents and records for an agency.

CMMC Program requirements in this rule are designed to improve compliance with requirements for safeguarding of FCI and CUI. DoD has privity of contract to enforce these requirements and CISA does not. OSAs are free to choose CISA services as part of their implementation of DoD requirements. FISMA is for Federal systems that are used by Government personnel or the public and is therefore an unsuitable surrogate for CMMC requirements. If a contractor provides outsourced IT services to a Federal agency, the system is considered a Federal system and FISMA applies. In contrast, CMMC requirements apply to nonfederal systems that are used internally by contractor personnel. The DoD disagreed with the commenter's assertions about NIST SP 800-171 R2 and the available assessment methods. DoD's DIBCAC currently performs assessments using the procedures in NIST SP 800-171A Jun2018, and these documents explicitly identify the target audience to include individuals with security assessment responsibilities, such as auditors, assessors, and independent verifiers. The aggregated SPRS reporting and scoring is CUI. The DoD does not wish to make this information public, which might aid adversaries in coordinating their attacks. The CMMC Program does not alleviate or supersede any existing requirements of the Adaptive Acquisition Framework, nor does CMMC alter any statutory or regulatory requirement for acquisition program documentation or deliverables. One commenter referenced assessments required during the acquisition process for DoD systems. DoD's policies governing acquisition programs require that Independent Technical Risk Assessments be conducted on Major Defense Acquisition Programs. These assessments provide a view of program technical risk and are not well-suited to the assessment of contractor owned information systems against standards for safeguarding CUI. CMMC assessments are conducted on contractor owned information systems to gauge compliance with FAR and DFARS requirements for safeguarding FCI and CUI that is processed, stored, or transmitted within those contractor-owned information systems. One commenter incorrectly asserts that the CMMC Scoring Methodology does not parallel existing scoring methods, however the CMMC methodology is based on the DoDAM. The DoD declined to accept the recommended alternative of self-assessment with the potential to require DIBCAC assessment for a sampling of DoD contractors, which is essentially the status quo. Both GAO reporting and other DoD analysis have shown that the DIB has not consistently implemented the NIST SP 800-171 requirements needed to comply with DFARS clause 252.204-7012, even though DoD's objective was for the contractor to implement NIST SP 800-171 as soon as practical, but not later than December 31, 2017.

14. CMMC Assessment Timeline Comment: Several comments requested details about CMMC assessment timelines, including how long an assessment would take, how long after an assessment was completed would the assessment report be ready, and when SPRS content would be updated. One commenter wanted to know how soon after a failed assessment a subsequent assessment could be scheduled. One commenter wanted details about the remediation period. Response: The actual length of time it takes for an OSA to prepare for, and assessors to conduct an assessment and prepare the assessment report depends on many factors, including the number of systems and networks in the CMMC Assessment Scope, the level of assessment being conducted, staff preparedness for assessor questions, and the number of assessors conducting the assessment. For CMMC assessments, C3PAOs will upload the results of the assessment and the signed CMMC certificate into the CMMC instantiation of eMASS. Certification is automatically posted to SPRS. There is no minimum time to wait after a failed assessment before scheduling another assessment. A NOT MET requirement may be re-evaluated during the course of the assessment and for 10 business days following the active assessment period under certain conditions, as set forth in § 170.17(c)(2) and § 170.18(c)(2). A Level 2 or Level 3 conditional assessment and associated POA&M must be closed out within 180 days. 15. Assessment Delays and Award Impact Comment: Several commenters expressed concerns about the impact that delays in the assessment process would have on contract award. For example, if an assessment is held up, by no fault of the contractor, such that the results will not be available until after the award date, will the contractor be ineligible to receive the award or is there a process for delaying the award? Would the answer be the same for a reassessment of a contractor whose three-year assessment or certificate is expiring? On a related issue, one comment asked about the timing of reassessment/recertification and whether work on an existing contract can continue after an assessment/certificate has expired if the reassessment is scheduled but delayed. Response: The CMMC Program rule does not provide mitigations for assessment delays that may impact timeliness of certification or recertification

with regard to the closing date of a particular solicitation. Offerors will be required to attain CMMC certification, when applicable, at or (printed page 89073) above the level in the solicitation, by the time of award (or option period exercise) and must maintain their CMMC status throughout the life of the contract, task order, or delivery order. The three-year validity period should provide adequate time to prepare for and schedule subsequent assessments for certification. Timelines for meeting CMMC requirements for Level 1 or 2 self-assessment are within the control of the contractor. 16. Defense Contractor and Subcontractor Engagement Comment:

ocker or Pods). Many cybersecurity vulnerability scanners are not optimized for scanning containers, resulting in an inability to identify certain vulnerabilities and a high number of false positives.

- In the healthcare of a patient, the nature and size of genomic data present a challenge with incorporating it into EHR workflows. Fast Healthcare Interoperability Resources (FHIR) as a genomic cybersecurity solution provides important security features, such as tracking provenance and consent as well as providing encryption for privacy. However, additional work is needed to scale up for genomic data size files. - Exploiting variant calling solutions is one example of how third-party tools can be compromised. Most of these tools are open source and may not have been vetted using best security practices or may not have been assessed for data consistency and reliability. Protecting computational technologies used in variant calling requires considering the security of the entire equipment, software, and application chain, as well as the

952. · See ·Area Health Resources Files,· Health Resources & Services Administration, U.S. Department of Health and Human Services (2022-2023 County Level Data), <https://data.hrsa.gov/data/download?data=·AHRF#AHRF> . Back to Citation 953. · See ·2021 [Statistics of U.S. Businesses] SUSB Annual Data Tables by Establishment Industry,· supra note 947. Back to Citation 954. · See ·Delineation Files,· U.S. Census Bureau, U.S. Department of Commerce (2023), <https://www.census.gov/geographies/reference-files/time-series/demo/metro-micro/delineation-files.html> . Back to Citation 955. See generally 86 FR 37770 (July 16, 2021). Back to Citation 956. · See 86 FR 37770 , 37778 (July 16, 2021). Back to Citation 957. 78 FR 5565 (Jan. 25, 2013). Back to Citation 958. · See ·Medical Expenditure Panel Survey-Insurance Component,· Tables I.A.1 and I.A.2, Agency for Healthcare Research and Quality (2023), https://meps.ahrq.gov/data_stats/summ_tables/insr/national/series_1/2023/ic23_ia_g.pdf?_gl=1*16xft35*_ga*MTE0MDI5NzI0LjE3MDk2NjQ0NDM.*_ga_45NDTD15CJ*MTczMTEwMzQ0S4yLjEuMTczMTEwMzUzNS4xNC4wLjA (showing the number of establishments and percent offering health plans) and ·County Business Patterns: 2021,· United States Census Bureau (April 27, 2023), <https://www.census.gov/data/datasets/2021/econ/cbp/2021-cbp.html> (providing the ratio of firms to establishments). We assume one health plan sponsor per firm that offers a self-insured group health plan. Back to Citation 959. · See ·Annual Report to Congress on Breaches of Unsecured Protected Health Information for Calendar Year 2022,· supra note 213, p. 9 (2023). Back to Citation 960. · See Steve Alder, ·December 2023 Healthcare Data Breach Report,· The HIPAA Journal (Jan. 18, 2024), <https://www.hipaajournal.com/december-2023-healthcare-data-breach-report/> . Back to Citation 961. · See ·What We Learned: Change Healthcare Cyber Attack,· U.S. House of Representatives Committee on Energy & Commerce (May 3, 2024), <https://energycommerce.house.gov/posts/what-we-learned-change-healthcare-cyber-attack> . Back to Citation 962. · See table 3, wage rate for Office and Administrative Support Occupations. Back to Citation 963. ·As defined by having 500 or fewer employees. See ·2021 [Statistics of U.S. Businesses] SUSB Annual Data Tables by Establishment Industry,· supra, note 947. Back to Citation 964. ·This is the estimated total number of covered entities and business associates. Back to Citation 965. · See 45 CFR 164.314(b) (requiring that a group health plan ensure that its plan documents provide that the plan sponsor will reasonably and appropriately safeguard electronic protected health information created, received, maintained, or transmitted to or by the plan sponsor on behalf of the group health plan). Back to Citation 966. · See ·Cost of a Data Breach Report 2023,· supra note 131, p. 13. Back to Citation 967. Id. at 18. Back to Citation

3.1.1 | General... 3.1.1 Local Vulnerability Prevalence (LVP) The Local Vulnerability Prevalence metric measures the prevalence of vulnerable systems in a specific environment. 3.1.1 General SCORING TIP #1: Configuration issue scoring should not take into account any interaction with other configuration issues, software flaws, or vulnerabilities.

All filers using the portal should use the name of the person or entity submitting comments as the

name of their files, in accordance with the instructions below. Anyone submitting business confidential/proprietary information should clearly identify any business confidential/proprietary portion at the time of submission, file a statement justifying nondisclosure and referencing the specific legal authority claimed, and provide a non-confidential/non-proprietary version of the submission. Any business confidential information should be in an uploaded file that has a file name beginning with the characters ·BC·. Any page containing business confidential information must be clearly marked ·BUSINESS CONFIDENTIAL/PROPRIETARY· on the top of that page. The corresponding non-confidential/non-proprietary version of those comments must be clearly marked ·PUBLIC·. The file name of the non-confidential version should begin with the character ·P·. The ·BC· and ·P· should be followed by the name of the person or entity submitting the comments or rebuttal comments. All filers should name their files using the name of the person or entity submitting the comments. Any submissions with file names that do not begin with a ·BC· will be assumed to be public and will be made publicly available through <https://www.regulations.gov>. To confirm receipt of your comment(s), please check <https://www.regulations.gov>, approximately two-to-three days after submission to verify posting. FOR FURTHER INFORMATION CONTACT: For clarification of content, contact Mr. Michael O. Jackson, Procurement Analyst, at 202-821-9776 or by email at michaelo.jackson@gsa.gov. For information pertaining to status, publication schedules, or alternate instructions for submitting comments if <https://www.regulations.gov> cannot be used, contact the Regulatory Secretariat Division at 202-501-4755 or GSARegSec@gsa.gov. Please cite FAR Case 2017-016. SUPPLEMENTARY INFORMATION: I. Background Today, Federal information and information systems are increasingly the targets of sophisticated attacks by criminals and our adversaries, as well as subject to risks involving non-adversarial threats (e.g., accidental misuse of information). Executive Order (E.O.) 13556, Controlled Unclassified Information, established the Controlled Unclassified Information (CUI) Program to manage information that requires safeguarding or dissemination controls and designated the National Archives and Records Administration (NARA) as the executive agent of the CUI Program. NARA published a final rule on September 14, 2016 (81 FR 63324) to implement the CUI requirements of E.O. 13556. As part of the implementation of the NARA final rule, NARA maintains a registry (<https://www.archives.gov/cui>

525. · See ·Security Standards: Administrative Safeguards,· supra note 517, p. 5-6. Back to Citation 526. See id. at 6. Back to Citation 527. Id. Back to Citation 528. · See ·Managing Malicious Insider Threats,· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Aug. 2019), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-summer-2019/index.html>. Back to Citation 529. Id. Back to Citation 530. Id. Back to Citation 531. Id. Back to Citation 532. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461, p. 33. Back to Citation 533. See id. at 34. Back to Citation 534. See id. Back to Citation 535. · See ·Security Standards: Administrative Safeguards,· supra note 517, p. 7; see also ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461, p. 30-34. Back to Citation 536. · See Press Release, ·HHS Office for Civil Rights Settles HIPAA Security Rule Failures for \$950,000,· U.S. Department of Health and Human Services (July 1, 2024), <https://prod-wwwhhs.gov.cloud.hhs.gov/about/news/2024/07/01/hhs-office-civil-rights-settles-hipaa-security-rule-failures-950000.html>. Back to Citation 537. See ·Montefiore Medical Center,· supra note 248. Back to Citation 538. · See 45 CFR 164.308(a)(1)(ii)(D). Back to Citation 539. · See ·Doctors' Management Services, Inc.,· supra note 246. Back to Citation 540. Id. Back to Citation 541. · See proposed 45 CFR 164.308(a)(12)(ii)(B). Back to Citation 542. · See ·Security Standards: Administrative Safeguards,· supra note 517, p. 7. Back to Citation 543. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461. Back to Citation 544. · See Press Release, ·City Health Department failed to terminate former employee's access to protected health information,· U.S. Department of Health and Human Services (Oct. 30, 2020), <https://public3.pagefreezer.com/content/HHS.gov/31-12-2020T08:51/https://www.hhs.gov/about/news/2020/10/30/city-health-department-failed-terminate-former-employees-access-protected-health-information.html>. Back to Citation 545. · See ·Security Standards: Administrative Safeguards,· supra note 517, p. 8-11. Back to Citation 546. · See ·Summary of the HIPAA Security Rule,· U.S. Department of Health and Human Services (Oct. 19, 2022), <https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html>. Back to Citation 547. · See 45 CFR 164.502(b) and 164.514(d). Back to Citation 548.

See ·Security Standards: Administrative Safeguards,· supra note 517, p. 9. Back to Citation
549. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA)
Security Rule: A Cybersecurity Resource Guide,· supra note 461.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204, 232, and 252 [Docket DARS-2019-0047] RIN 0750-AJ52 AGENCY: Defense Acquisition Regulation System, Department of Defense (DoD). ACTION: Proposed rule. SUMMARY: DoD is proposing to amend the Defense Federal Acquisition Regulation Supplement to provide for expedited contract closeout through a waiver by the contractor and the Government of entitlement to any residual dollar amounts that are due to either party at the time of final contract closeout. The changes are necessary to establish an expedited contract closeout agreement that will save administrative costs for both the contractor and the Government. DATES: Comments on the proposed rule should be submitted in writing using one of the methods shown in ADDRESSES on or before June 8, 2020, to be considered in the formation of a final rule. ADDRESSES: Submit comments in response to DFARS CASE 2017-D042 by any of the following methods: Regulations.gov: <http://www.regulations.gov> . Submit comments via Federal Rulemaking portal by entering ·DFARS Case 2017-D042· under the heading ·Enter keyword of ID· and selecting ·Search·. Select the link ·Submit a Comment· that corresponds with ·DFARS Case 2017-D042·. Follow the instructions provided at the ·Submit a Comment· screen. Please include your name, company name (if any), and ·DFARS Case 2017-D042· on your attached document. Email: osd.dfars@mail.mil . Include DFARS Case 2017-D042 in the subject line of the message. Fax: 571-372-6094. Mail: Defense Acquisition Regulations System, Attn: Ms. Kimberly Bass, OUSD(A&S)DPC/DARS, Room 3B941, 3060 Defense Pentagon, Washington, DC 20301-3060. Comments received generally will be posted without change to <http://www.regulation.gov> , including any personal information provided. To confirm receipt of your comment(s), please check www.regulations.gov , approximately two to three days after submission to verify posting (except allow 30 days for posting of comments submitted by mail). FOR FURTHER INFORMATION CONTACT: Ms. Kimberly Bass, telephone 571-372-6174. SUPPLEMENTARY INFORMATION: I. Background

Comment: Section 159.6(a)(ii) ·PSC verification that PSCs meet all the legal, training, and qualification requirements * * *. should include ·That the FAR shall be revised to require the insertion into each covered contract of a contract clause; addressing the selection, training, equipping and conduct of personnel performing private security functions under such a contract·. Response: A FAR clause will be drafted to incorporate all of the requirements of this Rule.
Comment: Section 159.6(a)(v) ·Reporting alleged criminal activity and other incidents involving PSCs or PSC personnel by another company or any other personnel. All incidents shall be reported and documented·. These reporting requirements are already required Response: Many of the requirements in this rule are already in effect in the CENTCOM AOR. With this Rule, we are establishing the requirements for all Geographic Combatant Commanders and Chiefs of Mission in order to extend guidance and procedures globally and to the wider interagency community. Comment: Questions of the propriety of having PSCs represent the U.S. in contingency operations relative to the U.S. Constitution and the Anti Pinkerton Act Response: The DoD's use of contractors, including private security (printed page 49653) contractors, is entirely consistent with existing U.S. Government policy on inherently governmental functions. We are guided by four main documents when determining whether an activity or function is inherently governmental: DoD Instruction 1100.22 ·Policy and Procedures for Determining Workforce Mix·; the Federal Acquisition Regulations (FAR); the Performance of Commercial Activities and the Federal Activities Inventory Reform Act, or FAIR Act, of 1998; and, Office of Management and Budget (OMB) Policy Letter 92-1, issued in 1992. The DoD recognizes that there are specific security functions that are inherently governmental and cannot be contracted. The DoD does not contract those functions, but there are other security functions that are appropriate to contract. The DoD, the Government Accountability Office (GAO), the Office of Management and Budget (OMB), the Congressional Budget Office (CBO), and the Congressional Research Service (CRS) have continuously reviewed the use of PSCs, the potential for their performance of inherently governmental functions, and the appropriateness and manner in which they are employed.
Comment: Opposition to the use of mercenaries in the U.S. Department of Defense Response:

3.6.2 | Authorization Mechanisms... 3.6.2 for more details. 3.6.2 Authorization Mechanisms Some recovery and administrative actions can make significant changes to either the Platform Firmware or software.

DoD is planning for a phased roll-out of each assessment level across 7 years with the entity numbers reaching a maximum by Year 4 as shown in the tables. The target of Year 4 was selected based on the projected capacity of the CMMC Ecosystem to grow to efficiently support the entities in the pipeline. For modeling efficiency, a similar roll-out is assumed regardless of entity size or assessment level. It is assumed that by year 7 the maximum number of entities is reached. Beyond year 7, the number of entities entering and exiting are expected to net to zero. The following tables reflect the number of new entities in each year and for each level. (printed page 83178)

Public Costs Summary of Impacted Awardee Entities According to data available in the Electronic Data Access system for fiscal years (FYs) 2019, 2020, and 2021, DoD awards an average of 1,366,262 contracts and orders per year that contain DFARS clause 252.204-7012, to 31,338 unique awardees, of which 683,718 awards (50%) are made to 23,475 small entities (75%). [37]

Public Cost Analysis The following is a summary of the estimated Public costs the revised CMMC Program for other than small [38] entities, per assessment of a contractor information system, at the required periodicity for each CMMC level. The following is a summary of the estimated Public costs of the revised CMMC Program for Small Entities, per assessment of each contractor information system, estimated at one per entity, at the required periodicity for each CMMC level. (printed page 83179)

The total estimated Public (large and small entities) costs associated with this rule, calculated for a 20-year horizon in 2023 dollars at a 7 percent and 3 percent discount rate, per OMB guidance, is provided as follows:

Assumptions In estimating the Public costs, DoD considered applicable nonrecurring engineering costs, recurring engineering costs, [41] assessment costs, and affirmation costs for each CMMC Level. For CMMC Levels 1 and 2, the cost estimates are based only upon the self-assessment, certification assessment, and affirmation activities that a defense contractor, subcontractor, or ecosystem member must take to allow DoD to verify implementation of the relevant underlying security requirements, i.e.,

In the final rule, guidance on the use of an evaluation factor regarding supply chain risk is modified to require the inclusion of the evaluation factor when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system. Risk levels, risk tolerance, and appropriate risk management measures must be determined at the local level. Evaluation factors are specified at the individual acquisition level and not in the DFARS. DoD is issuing DFARS Procedures, Guidance, and Information for the contracting workforce on developing and using supply chain risk evaluation factors.

c. Information Sharing Comment: Three respondents commented on the disclosure of information regarding supply chain risk to offerors and contractors. One of these respondents urged the DoD to use its discretion in sharing information concerning threats sufficient to allow suppliers to alter product designs and change components on devices to overcome known vulnerabilities. Another respondent suggested that a requirement to report identified supply chain risks and issues would assure that immediate remediation could be undertaken if problems arose. One respondent commented that DoD should consider revising the rule to promote disclosure of information regarding supply chain risks to offerors and contractors whenever possible. Whenever such notice may be accomplished consistent with the requirements of national security, DoD should provide notification to the offeror or contractor of perceived supply chain risks early in the procurement process in accordance with standard Government procurement rules (e.g., during discussions in a negotiated procurement), so that the contractor has the opportunity to mitigate or eliminate the risk. Contractors are less able to mitigate supply chain risk if the Government fails or declines to share with them risk information it has developed internally. Response: The DoD intends to share information about supply chain risk with its contractors to the extent possible, consistent with the requirements of national security. The provisions of the rule and section 806 that limit disclosure are concerned with risk information that, for national security reasons, cannot be shared despite the transparency that is normally present in procurement activities.

d. Mitigation/Less Intrusive Measures Comment:

From the NIST SP 800-172 Rev 3 Final Public Draft: architectures can also include other information, such as user roles and the access 2424 privileges assigned to each role; security requirements; types of information processed, stored, and transmitted by the system; cybersecurity supply chain risk management (CSCRM) requirements; restoration priorities of information and

system services; and other protection needs. With the use of modern computing technologies, it is becoming less common for organizations to control all information resources. There may be key dependencies on external services and service providers. Describing such dependencies as part of the security architecture is necessary for developing a comprehensive CUI protection strategy. Establishing, documenting, and maintaining a baseline configuration for organiza

(Comment 43) One comment argues that the proposed retail exemption (§ 1.327(d)) must be a complete exemption, including an exemption from recordkeeping regarding suppliers, identical to the exemption given to restaurants. The comment states that today retailers and restaurants compete in the burgeoning take home and carryout market. FDA's proposal gives an unfair and unnecessary advantage to restaurants, which are expanding out of in-restaurant dining into areas formerly served by retailers and carryout establishments. A full exemption for retailers presents no lessening of food safety safeguards. (Response) Restaurant is defined to mean a facility that prepares and sells food directly to consumers for immediate consumption. This means that an establishment that prepares and sells food that is capable of being eaten immediately, with no further preparation, is considered a restaurant. This definition and the corresponding exemption for restaurants in § 1.327(b) of the final rule includes activities such as a restaurant preparing and selling food to a consumer to be consumed at a later time, as long as the food is (printed page 71578) capable of being immediately consumed without further preparation or processing. For example, a restaurant may prepare and sell pies from a counter that consumers purchase and take home for later consumption. This activity qualifies for the restaurant exemption as long as the food is prepared and sold directly to a consumer for immediate consumption. In addition, a restaurant/retail facility is excluded from all of the requirements in subpart J of this final rule if its sales of food it prepares and sells to consumers for immediate consumption are more than 90 percent of its total food sales. FDA notes that many facilities that otherwise would be excluded as restaurants under the final rule sell a small amount of food that they do not prepare for immediate consumption. For example, some restaurant/retail facilities have small packaged goods gift shop areas that sell food. The entire facility is excluded from all of the requirements in subpart J if its sales of food it prepares and sells to consumers for immediate consumption are more than 90 percent of its total food sales. FDA exercised its discretion and excluded restaurant/retail facilities whose nonrestaurant food sales are less than 10 percent of their total food sales because many facilities that would otherwise qualify as restaurants make such sales as an incidental activity (Ref. 14). FDA believes that, were it not to provide such an exclusion, the exemption for restaurants would be undermined because many facilities that prepare and sell a high percentage of their food for immediate consumption also sell a small amount of packaged goods that they do not prepare themselves for sale to consumers (e.g., beverages, chips, candy, condiments, and sweeteners) and otherwise would be subject to the rule as to those sales.

CMMC Phase 1 (effective November 10, 2025) focuses on self-assessments. DoD is incorporating CMMC Level 1 and Level 2 self-assessment requirements into applicable solicitations and contracts. Organizations can demonstrate compliance through self-assessment during this phase. CMMC Phase 2 (scheduled November 10, 2026) expands the requirements to include C3PAO certification assessments. This means solicitations and contracts may require organizations to have undergone a third-party assessment by an authorized C3PAO and received a CMMC Level 2 certification. Phase 2 is when the independent assessment requirement becomes enforceable. The practical difference: in Phase 1, you self-attest. In Phase 2, a C3PAO verifies your implementation.

This program benefits the Department by increasing awareness and improving assessments of cyber incidents that may affect mission critical capabilities and services. It continues to be an important element of the Department's comprehensive effort to defend DoD information, protect U.S. national interests against cyber-attacks, and support military operations and contingency plans worldwide. Once a defense contractor joins the program, they are encouraged to share information, including cyber threat indicators, that they believe may be of value in alerting the Government and others, as appropriate, of adversary activity to enable the development of mitigation strategies and proactively counter threat actor activity. DC3 develops written products that include analysis of the threat, mitigations, and indicators of adversary activity. Even cyber incidents that are not compromises of covered defense information may be of interest to DoD for situational awareness purposes. This information is disseminated as anonymized threat products that are shared with authorized DoD personnel, other Federal agencies, and company-designated POCs participating in the DIB CS Program. With the revisions to the eligibility criteria, the Department will be able to

reduce the impact of cyber threat activity on DIB networks and information systems and, in turn, preserve its technological advantage and protect DoD information and warfighting capabilities. The mitigation of the cyber threat targeting defense contractors reinforces the nation's national security and economic vitality. For DIB participants, this program provides valuable cyber threat information they cannot obtain from anywhere else and technical assistance through analyst-to-analyst exchanges, mitigation and remediation strategies, and cybersecurity best practices in a collaborative environment. The shared unclassified and classified cyber threat information is used to bolster a company's cybersecurity posture and mitigate the growing cyber threat. The program's tailored support for small, mid-size, and large companies with varying cybersecurity maturity levels is an asset for participants. The program remains a key element of DoD's cybersecurity efforts by providing services to help protect DIB CS Program participants and the sensitive DoD information they handle. Alternatives Alternative #1 Maintain status quo with the ongoing voluntary cybersecurity program for cleared defense contractors. Reason for Not Selecting Alternative #1

(Aug. 24, 2009). The Department also finalized previously proposed Privacy Rule modifications as required by the Genetic Information Nondiscrimination Act of 2008, 74 FR 51698 (Oct. 7, 2009). Back to Citation 100. 78 FR 5565 , 5589 (Jan. 25, 2013). Back to Citation 101. Sec. 13401 of Public Law 111-5 , 123 Stat. 260 (Feb. 17, 2009) (codified at 42 U.S.C. 17931). Back to Citation 102. 78 FR 5565 , 5590 (Jan. 25, 2013); see also 45 CFR 164.314(a) . Back to Citation 103. 78 FR 5565 , 5589 (Jan. 25, 2013). Back to Citation 104. 68 FR 8334 , 8341 (Feb. 20, 2003). Back to Citation 105. 78 FR 5565 , 5589 (Jan. 25, 2013). Back to Citation 106. Id. at 5590. Back to Citation 107. Id. (citing 45 CFR 164.308(b)). Back to Citation 108. As technology has evolved and cybercriminals have become more sophisticated, protective measures, including technology, have been developed to prevent and mitigate such risks. For example, certain health IT may be certified through the ONC Health IT Certification Program as meeting certain criteria that address the security of information created, received, maintained, or transmitted by that health IT. See 45 CFR 170.550(h) . Back to Citation 109. 45 CFR 164.306(b) . Back to Citation 110. 45 CFR 164.310(a)(1) . Back to Citation 111. 45 CFR 164.310(a)(2) . Back to Citation 112. National Trends in Hospital and Physician Adoption of Electronic Health Records, The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, <https://www.healthit.gov/data/quickstats/national-trends-hospital-and-physician-adoption-electronic-health-records> . Back to Citation 113. See 2020-2025 Federal Health IT Strategic Plan, The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, p. 6 (Oct. 2020), https://www.healthit.gov/sites/default/files/page/2020-10/Federal%20Health%20IT%20Strategic%20Plan_2020_2025.pdf . Back to Citation 114. Among other things, the Cures Act provided ONC, in collaboration with NIST and other relevant agencies within the Department, with the authority to convene public-private and public-public partnerships to build consensus and develop or support a trusted exchange framework, including a common agreement among health information networks nationally. The purpose of this work is to ensure full network-to-network exchange of health information. Sec. 4003(b) of Public Law 114-255 , 130 Stat. 1165 (Dec. 13, 2016) (codified at 42 U.S.C. 300jj-11(c)). The Cures Act also provides penalties for any developer of certified health IT, health information exchange or network, and appropriate disincentives for any health care provider, determined by the Inspector General to have committed information blocking. Sec. 4004(b)(2) of Public Law 114-255 , 130 Stat. 1165 (Dec. 13, 2016) (codified at 42 U.S.C. 300jj-52) . Back to Citation

Revise Business Associate Agreements 1 × 1 1,822,600 Regulated Entities 169.68 309 Total Annual Cost Burden 4,655 a These represent first year estimated costs and are rounded. The Department presents the estimated cost of health plan sponsors' compliance with the proposed new requirements in table 7 below. Table 7·First Year Cost Estimates of Health Plan Sponsors' Proposed Compliance Obligations a Compliance activities Burden hours × frequency Respondents Wage rate Total annual cost (millions) Risk Analysis·Documentation 5 × 1 742,411 Plan Sponsors \$119.94 \$445 Information System Activity Review·Documentation .75 × 12 742,411 Plan Sponsors 119.94 801 Ongoing Education .17 × 12 742,411 Plan Sponsors 119.94 178 Security Incidents (other than breaches)·Documentation 2 × 12 742,411 Plan Sponsors 119.94 2,137 Contingency Plan·Testing and Revision 2 × 1 742,411 Plan Sponsors 119.94 178 Contingency Plan·Criticality Analysis .5 × 1 742,411 Plan Sponsors 119.94 45 Notification of Workforce Members' Termination of ePHI Access .25 × 1 742,411 Plan Sponsors 46.10 9 Maintenance Records .5 × 12 742,411 Plan Sponsors 111.08 495 Multi-factor Authentication 1.5 × 1 742,411 Plan Sponsors 119.94 133 Configuration

Management .5 × 1 742,411 Plan Sponsors 119.94 45 Penetration Testing 2 × 1 742,411 Plan Sponsors 119.94 178 Notification of Contingency Plan Activation .17 × 1 742,411 Plan Sponsors 119.94 15 Total Annual Cost Burden 4,659 a These represent first year estimated costs and are rounded. Together, regulated entities' and affected health plan sponsors' estimated first year costs of compliance with the proposals in the NPRM would be approximately 9,314 million (or \$9 billion). p. Costs Borne by the Department The covered entities that are operated by the Department would be affected by the changes in a similar manner to other covered entities, and such costs have been factored into the estimates above. The Department has not identified other costs to the Department related to the changes in the NPRM. A reduction in the number of large breaches (affecting 500 or more individuals per incident) would benefit the Department by enabling it to focus its resources on a smaller number of breach investigations, and potentially resolve such investigations more quickly. 4. Benefits of the Proposed Rule a. Quantitative Analysis of Benefits A key goal of strengthening the cybersecurity posture of regulated entities is to reduce the number and severity of security incidents, including breaches of ePHI. The Department believes that compliance with the proposed changes, which align with industry guidelines and best practices, would benefit regulated entities by reducing the cost of breaches. Although the costs of implementing the proposed cybersecurity measures would be significant, the costs of responding to breaches of ePHI are much higher. According to industry data, the average cost of a health care breach in 2023 rose to \$10.93 million, the highest among all industries studied, [966]

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations. 1. Broad network access : Cloud services are available over the network and accessible through standard mechanisms that promote use by heterogeneous thick and thin client platforms (e.g., mobile phones, tablets, laptops, workstations). This raises security concerns with regard to network access. For example, denial of service (DoS) attacks can be launched against a cloud system, rendering its resources unavailable to legitimate users. Thus, AC for network access should be managed. 2. Resource pooling : The computing resources of a cloud system (e.g., storage, memory, processing, network bandwidth) are pooled to serve multiple consumers using a multitenant model (i.e., a single instance of the software and its supporting infrastructure serves multiple consumers) through different physical and virtual resources, each dynamically assigned and reassigned according to consumer demands.

CMMC requirements apply to prime contractors and subcontractors throughout the supply chain at all tiers that will process, store, or transmit any FCI or CUI on contractor information systems in the performance of the DoD contract or subcontract, irrespective of the origin of the information. The executive branch's CUI Program is codified in 32 CFR part 2002 and establishes policy for designating, handling, and decontrolling information that qualifies as CUI. The definition of CUI and general requirements for its safeguarding are included in 32 CFR 2002.4 and 2002.14 , respectively. 32 CFR 2002.14(h)(2) specifically requires agencies to use NIST SP 800-171 when establishing security requirements to protect CUI's confidentiality on non-Federal information systems. At the time of award, the DoD may have no visibility into whether the awardee will choose to further disseminate DoD's CUI, but DFARS clause 252.204-7012 and DFARS clause 252.204-7021 require the prime contractor to flow down the information security requirement to any subcontractor with which the CUI will be shared. Decisions regarding which DoD information must be shared to support completion of subcontractor tasks is between the prime contractor and the subcontractors. The DoD encourages prime contractors to work with subcontractors to lessen the burden of flowing down CUI. The DoD declines to adopt alternatives such as policy-based solutions that lack a rigorous assessment component or require sharing CUI only through DoD-hosted secure platforms. Suggested alternatives to implementing NIST SP 800-171 and identifying what data is CUI are beyond the scope of the CMMC Program and this rule. b. FCI and CUI Definitions Comment: Five comments stated that what DoD considers CUI is not well defined. Another comment stated that companies should be provided a reference list of what the DoD considers CUI. Another recommended DoD use existing mechanisms like

the DD Form 254 architecture to clearly define the scope of CUI on a contract-by-contract basis. Seven comments recommended the CMMC rule mandate a Security Classification Guide (SCG) or similar document. Nine comments stated there was too much confusion and ambiguity regarding FCI and CUI and that the government needed to provide clear and standardized FCI and CUI definitions that are tailored to the specific requirements of the CMMC rule. One comment recommended rule edits to address this perceived ambiguity. One comment requested clarification and examples of differences between CUI Basic and Specialized CUI. Response: Federal Contract Information is defined in FAR clause 52.204-21, which also provides the security requirements applicable for basic safeguarding of such information. The DoD has no authority to modify definitions established in the FAR for application to all executive branch agencies. This rule makes no change to the definition or handling of CUI. c. Marking Requirements Comment:

3.1.4 Travel Information Type... 3.1.4 Travel Information Type Travel involves the activities associated with planning, preparing, and monitoring of business related travel for an organization's employees.

For purposes of this part, a signed agreement between a foreign interest and a U.S. contractor or a company in process for an FCL which, based on an assessment of FOCI information, imposes various security measures within an institutionalized set of company practices and procedures. Examples include board resolutions, security control agreements (SCAs) and special security agreements. FOCI negotiation agreement. For purposes of this part, a signed agreement between a foreign interest and U.S. contractor or a company in process for an FCL under which the foreign owner relinquishes most ownership rights to U.S. citizens who are approved by the U.S. Government and have been favorably adjudicated for access to classified information based on the results of a personnel security clearance investigation. Examples include voting trust agreements (VTAs) and proxy agreements (PAs). Foreign government information (FGI). As defined in E.O. 13526 . Foreign interest. As defined in DoD 5220.22-M. GCA. As defined in DoD 5220.22-M. Industrial security. As defined in DoD 5220.22-M. Information. As defined in E.O. 13526 . (printed page 19471) Limited Access Authorization (LAA). As defined in DoD 5220.22-M. National interest determination (NID). As defined in 32 CFR part 2004 , ·National Industrial Security Program Directive No. 1.· Non-DoD Components. Those USG executive branch departments and agencies identified in DoD 5220.22-M that have entered into agreements with the Secretary of Defense to act as the NISP Cognizant Security Agency (CSA) for, and on their behalf, in rendering security services for the protection of classified information disclosed to or generated by industry pursuant to Section 202 of E.O. 12829 . Personnel security clearance (PCL). As defined in DoD 5220.22-M. Personnel security clearance assurance (PCLSA). A written certification by USG or applicable foreign government industrial security authorities, which certifies the PCL level or eligibility for a PCL at a specified level for their citizens. The assurance is used, in the case of the United States, to give an LAA to a non-U.S. citizen, provided all other investigative requirements are met. Prime contract. As defined in DoD 5220.22-M. Proscribed information. TOP SECRET (TS) information, COMSEC information excluding controlled cryptographic items when unkeyed and utilized with unclassified keys, restricted data (RD), special access program (SAP) information, or sensitive compartmented information (SCI). Restricted Data (RD). As defined in DoD 5220.22-M. Sensitive compartmented information (SCI). As defined in Joint Publication 1-02. Security assurance.

Satellite-to-satellite communications sub-segment. Communications between operational satellites for mission functions - such as command and control, networking of compute capabilities, redundancy of operations and mission functions, tracking, and communications are known as inter-vehicle communications . Therefore, the integrity, availability, and confidentiality of these communications are critical. Satellite-to-satellite communications is a capability of a satellite in the space segment and can be for both docked systems as well as space stations, which are composed of separate operational vehicles. The cybersecurity risks of decommissioning should consider appropriate confidentiality, integrity, and availability considerations, as well as related physical threats to commercial satellite systems once decommissioned. Industry practices - such as following International Organisation for Standards (ISO) standards for decommissioning, international treaty obligations, and domestic regulations - should also be considered.

does impose reporting or recordkeeping requirements under the Paperwork Reduction Act of 1995. These requirements have been approved by OMB and assigned OMB Control Numbers 0704-0460, ·Synchronized Predeployment and Operational Tracker (SPOT) System· and 0704-0461, ·Qualification to Possess

Firearms or Ammunition. Executive Order 13132, Federalism. It has been certified that 32 CFR part 159 does not have federalism implications, as set forth in Executive Order 13132. This rule does not have substantial direct effects on: (1) The States; (2) The relationship between the National Government and the States; or (3) The distribution of power and responsibilities among the various levels of Government. List of Subjects in 32 CFR Part 159 Contracts Security measures. Accordingly, the interim rule amending 32 CFR part 159 which was published at 74 FR 34691 on July 17, 2009, is adopted as a final rule with the following change. Part 159 is revised to read as follows: PART 159-PRIVATE SECURITY CONTRACTORS OPERATING IN CONTINGENCY OPERATIONS 159.1 Purpose. 159.2 Applicability and scope. 159.3 Definitions. 159.4 Policy. 159.5 Responsibilities. 159.6 Procedures. Authority: Pub. L. 110-181; Pub. L. 110-417. § 159.1 Purpose. This part establishes policy, assigns responsibilities and provides procedures for the regulation of the selection, accountability, training, equipping, and conduct of personnel performing private security functions under a covered contract. It also assigns responsibilities and establishes procedures for incident reporting, use of and accountability for equipment, rules for the use of force, and a process for administrative action or the removal, as appropriate, of PSCs and PSC personnel. § 159.2 Applicability and scope. This part: (a) Applies to: (1) The Office of the Secretary of Defense, the Military Departments, the Office of the Chairman of the Joint Chiefs of Staff and the Joint Staff, the Combatant Commands, the Office of the Inspector General of the Department of Defense, the Defense Agencies, the DoD Field Activities, and all other organizational entities in the Department of Defense (hereafter referred to as the DoD Components). (2) The Department of State and other U.S. Federal agencies insofar as it implements the requirements of section 862 of Public Law 110-181.

If the Contractor is operating a non-Federal information system that processes, stores, or transmits CUI identified in the contract, the CUI clause requires the contractor to comply with the security requirements in NIST Special Publication 800-171, Revision 2, or as authorized by the Contracting Officer and any CUI specified requirements identified in the SF XXX. NIST SP 800-171 Revision 2 includes 110 security requirements for non-Federal information systems that can be grouped into the following 14 categories: access control, awareness and training, audit and accountability, configuration management, identification and authentication, incident response, maintenance, media protection, personnel security, physical protection, risk assessment, security assessment, system and communications protection, and system and information integrity. Specific information on the 110 individual security requirements and various templates are available on the NIST website at <https://csrc.nist.gov/publications/detail/sp/800-171/rev-2/final>. Federal contractors that handle covered Federal information (CFI), a much broader category than CUI, on their information systems are already required to have implemented 17 of the 110 security requirements, which are already included in the clause at FAR 52.204-21, Basic Safeguarding of Covered Contractor Information Systems. Such requirements are considered met by all impacted contractors, regardless of size. For the remaining 93 security requirements, a contractor may need to establish a process or procedure, configure existing information technology that the contractor already owns, or acquire additional software or hardware. Assess and report suspected CUI incidents. When the Contractor discovers a suspected CUI incident, the CUI clause requires the contractor to determine what CUI was or could have been improperly accessed, used, processed, stored, maintained, disseminated, disclosed, or disposed of; construct a timeline of user activity; and determine methods and techniques used to access CUI. The Contractor shall report any suspected or confirmed CUI incident to the agency website or point of contact identified in the SF XXX, within 8 hours of discovery. The report shall include as many of the applicable data elements located on the DIBNet website as are available and provide any remaining applicable data elements as soon as they become available. In addition, if the Contractor is a FedRAMP authorized (Joint Authorization Board or Agency) Cloud Service Provider, the Contractor shall also report to the points of contact specified in the FedRAMP incident reporting guidelines as documented in the Cloud Service Provider Incident Response Plan. The requirements of the CUI clause are flowed down to subcontracts at all tiers; subcontractors are required to notify the prime contractor or next higher-tier subcontractor within the same timeframes.

A number of the routine uses listed in the System of Records Notice below are common to systems across the government. These include routine uses allowing disclosure to Federal Agencies as necessary in order to respond to a confirmed or suspected breach of system security or confidentiality (routine use number 1); to the Department of Justice (DOJ) to obtain DOJ advice on producing user fee records in response to a FOIA request (routine use 2); to DOJ when DOJ represents

the Agency in litigation (routine use 7); in response to a subpoena issued by a duly empowered Federal Agency (routine use 3); to a court or tribunal when the records are relevant and necessary to a proceeding involving the Agency or an employee (routine use 8); to contractors and others who perform services for the Agency related to the UFS (routine use 9); to the National Archives and Records Administration (NARA) and General Services Administration as needed in the course of records management inspections (routine use 10); and to the Department of Homeland Security (DHS) in circumstances where system records are captured in an intrusion detection program and made accessible to DHS (routine use 11). Additional routine uses specific to the UFS allow disclosure to entities as permitted under the Debt Collection Improvement Act (routine use 4); to banks in order to process payment made by credit card (routine use 5); and to Dun and Bradstreet to validate submitter contact information (routine use 6). SYSTEM NUMBER: 09-10-0021. SYSTEM NAME: FDA User Fee System, HHS/FDA. SECURITY CLASSIFICATION: Unclassified. SYSTEM LOCATION: This system is located at FDA's Data Center in Ashburn, VA. CATEGORIES OF INDIVIDUALS COVERED BY THE SYSTEM: This system contains records about individuals and companies that are required to submit user fee payments to the FDA. This includes organizations registered in the UFS, those billed through the system, as well as those submitting applications for review or otherwise assessed fees under the User Fee Program. Privacy Act notification, access, and amendment rights relative to the UFS are available only to individuals who are the subject of records in this system. User fee record subjects are individuals required to pay a user fee, including individual FOIA requestors and individuals who are sole proprietors of an entity required to pay a user fee. Although records in the system may contain personally identifiable information (PII) related to other individuals, only the specified fee submitters are considered subjects of records in this system. CATEGORIES OF RECORDS IN THE SYSTEM: 1. The UFS maintains information about individuals, companies and organizations that pay user fees. This includes: (a) For an entity remitter, a FEIN, and for an individual remitter, a TIN; (b) company or organization name and address; (c) DUNS number; and (d) contact person's name, phone number, Fax number, and email address.

b. For Level 2 assessments, if all 110 requirements are satisfied, the assessment score will be 110 and the OSA will have achieved a CMMC Status of Final Level 2 (Self) or Final Level 2 (C3PAO) as applicable and is eligible for contract award as long as all other contractual requirements are met. Not all requirements must immediately be MET to be eligible for contract award. If the minimum score is achieved on the assessment (equal to 80% of the maximum score) and certain critical requirements are met, OSAs will achieve a CMMC Status of Conditional Level 2 (Self) or Conditional Level 2 (C3PAO) as applicable. All NOT MET requirements must be noted in an assessment Plan of Action and Milestones (POA&M). At this point the OSA will have satisfied the CMMC requirements needed for contract award OSAs must have met all 110 security requirements of NIST SP 800-171 R2 within 180 days of receiving their Conditional CMMC Status, which must be verified with a second assessment, called a POA&M closeout assessment. If the POA&M closeout assessment finds that all requirements have been met, then the OSA will achieve a CMMC Status of Final Level 2 (Self) or Final Level 2 (C3PAO) as applicable. However, if a POA&M closeout assessment does not find that all requirements have been met by the end of 180 days, then the CMMC Status of Conditional Level 2 (Self) or Conditional Level 2 (C3PAO) will expire. At this point, standard contractual remedies will apply. The OSA should submit an affirmation into SPRS after achieving a CMMC Status of Conditional Level 2 (Self) or CMMC Status of Conditional Level 2 (C3PAO) as applicable. OSAs should submit an affirmation once a CMMC Status of Final Level 2 (Self) or Final Level 2 (C3PAO) as applicable is achieved. Being eligible for contracts subject to CMMC Level 2 (Self) also indicates eligibility for contracts subject to Level 1 (Self), and being eligible for contracts subject to CMMC Level 2 (C3PAO) also indicates eligibility for contracts subject to Level 1 (Self) and Level 2 (Self), assuming all other contractual requirements are met. OSAs must reaffirm in SPRS their compliance with CMMC Level 2 requirements annually but need only conduct a new assessment every three years. These deadlines are based on the CMMC Status Date of the Conditional Status if a POA&M was required or the Final Status if the assessment resulted in a score of 110. CMMC Status date is not based on the date of a POA&M closeout assessment. c. For Level 3 assessments, OSAs should note that asset categories are assessed against security requirements differently than they are at Level 2. In particular, Contractor Risk Managed Assets identified in a Level 2 scope are treated as CUI Assets if they reside within a Level 3 scope. Definitions and treatment of these assets at Level 3 as they relate to scoping of the assessment, in addition to treatment of ESPs, are described in §.170.19(d).

Section VI covers the formation of a Computer Security Incident Response Team. Although not explicitly required by federal directives, forming such a team is one method agencies are using to

deal with the threat of computer security incidents - o physical access controls and their effectiveness; - o locks and entry procedures; - o air conditioning, uninterruptable power supply, and fire suppression and pumping equipment for adequacy and proper maintenance; - o reports distribution; - o protection against hardware and software theft and other human and machine-related threats; - o procedures for off-site storage of data and software; - o procedures for reacting to natural disasters and other nature-based threats to the facility, such as flood, fire, earthquake, hurricane, or twister; and - o personal computer use and software copyright license policy. recertify the adequacy of safeguards. It specifies that this be done at least every 3 years and that audits and reviews be considered part of the agency vulnerability assessment and internal control reviews conducted in accordance with OMB Circular A-123.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA, CRS NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 ADVERSARY EFFECTS 2493

There were also discussions on the role of patching. While patching is important for ongoing device cybersecurity, it is not sufficient. There are too many exploits for patching alone to work, and there is concern about running out of time and money before bad actors do, given how quickly IoT changes. Updates on Program activities and collaboration opportunities are available on the NIST Cybersecurity for IoT Program website.

- · detect and prevent unauthorized software installation - · protect ICS networks from potentially harmful applications - · determine changes made to a network using change management tools - · detect unauthorized use of systems - · continuously monitor network traffic - · leverage anti-malware tools The NCCoE, in conjunction with the NIST EL, collaborated with cybersecurity technology providers to develop and implement example solutions that demonstrate how manufacturing organizations can protect the integrity of their data from destructive malware, insider threats, and unauthorized software within manufacturing environments that rely on ICS. An organization that is interested in protecting the integrity of a manufacturing system and information from destructive malware, insider threats, and unauthorized software should first conduct a risk assessment and determine the appropriate security capabilities required to mitigate those risks. Once the security capabilities are identified, the sample architecture and solution presented in this document may be used.

Following publication of this Final Rule, these requirements will be added to the FAR and DFARS and subsequently incorporated into appropriate contracts. This will provide a basis for the management of PSC compliance. Comment: Chief of Mission Should Be Required to Opt Out of DoD PSC Processes Response: We believe that the arrangement set out in Section 159.4(c) is appropriate and meets the congressional intent of a consistent approach towards PSCs operating in combat operations or other significant military operations, across USG agencies. Comment: Any Procedures or Guidance Issued Under the Requirements of This Rule Should be Subject to an Appropriate Rule-Making with an Adequate Opportunity for Public Comment Response: The relevant provisions of this Final Rule will be implemented through military regulations and orders, in accordance with existing procedures. Comment: The Rule is Not Integrated with Standard Contracting Processes Response: The requirements associated with GCC guidance and procedures will be included in any solicitations and therefore potential bidders will be aware of GCC specific procedures prior to submitting their proposals. AOR specific procedures such as training requirements are required to be placed on GCC Web sites immediately after a declared contingency so that the requirements can get into the appropriate contracts as soon as possible. Comment: The Rule Should Fully Explain How DoD Determines a PSC Law of War Status Response: It is not the role of the Rule to make statements regarding international law. Department Of Defense Instruction 3020.41, the overarching Defense policy document for this Rule, provides in paragraph 6.1.1 that: Under applicable law, contractors may support military operations as civilians accompanying the force, so long as such personnel have been designated as such by the force they accompany and are provided with an appropriate identification card under the provisions of the 1949 Geneva Convention Relative to the Treatment of Prisoners of War (GPW) (reference (j)). If captured during armed conflict, contingency contractor personnel accompanying the force are entitled to prisoner of war status. The comments regarding direct participation in hostilities are unsupportable. There is no agreement within the international community or among recognized authorities in international humanitarian law (LOAC) on a universally applicable definition for ·Direct Participation in Hostilities· (printed page 49652)

, 529 U.S. 120, 132 (2000). The agency has determined that, in enacting section 306 of the Bioterrorism Act, Congress did not speak directly and precisely to the meaning of “food.” The FD&C Act has a definition of “food” in section 201(f). It is a reasonable assumption that, when the term “food” is used in the Bioterrorism Act, section 201(f) applies. However, although there may be “a natural presumption that identical words used in different parts of the same Act are intended to have the same meaning [citation omitted], *** the presumption is not rigid***.” Atlantic Cleaners & Dyers, Inc. v. U.S., 286 U.S. 427, 433 (1932). Accord: U.S. v. Cleveland Indians Baseball Co., 532 U.S. 200, 213 (2000). Thus, the same word may be given different meanings, even in the same statute, if different interpretations are what Congress intended. Atlantic Cleaners & Dryers, Inc., supra. Even before the Bioterrorism Act amendments, the term “food” was not given an identical meaning throughout the FD&C Act. For example, in construing the parenthetical “(other than food)” in section 201(g)(1)(C) of the FD&C Act, the Seventh Circuit noted that Congress meant to exclude only “articles used by people in the ordinary way that most people use food primarily for taste, aroma, or nutritive value” and not all substances defined as food by section 201(f) of the FD&C Act. Nutrilab, Inc. v. Schweiker, 713 F.2d 335, 338 (7th Cir. 1983). Similarly, section 409(h)(6) of the FD&C Act defines a food contact substance as “any substance intended for use as a component of materials used in manufacturing, packing, packaging, transporting, or holding food if such use is not intended to have any technical effect in such food (emphasis added).” This definition makes sense only if “food” is interpreted to exclude materials that contact food because components of food contact materials are plainly intended to have a technical effect in such materials. [1] Thus, it is in this larger statutory context, that FDA has evaluated section 306 of the Bioterrorism Act to determine whether the meaning of the word “food” is ambiguous. In conducting this Chevron step one analysis, all of the traditional tools of statutory interpretation are available to determine whether Congress’s intent is ambiguous. Pharmaceutical Research & Manufacturers of America v. Thompson

| CSS | cascading style sheet | |-----|-----| | CSV
 | comma-separated values | | CTO | chief technology officer | | CTR | counter mode encryption | |
 CVE | Common Vulnerabilities and Exposures | | CVSS | Common Vulnerability Scoring System | | CWE |
 Common Weakness Enumeration | | D | | DA | destination address | | DAA | designated accrediting
 authority | | DAA | designated approving authority | | DAC | discretionary access control | | DAD |
 duplicate address detection | | DAML | DARPA Agent Markup Language | | D-AMPS | Digital Advanced
 Mobile Phone Service | | DAO | Data Access Object | | DARPA | Defense Advanced Research Projects
 Agency | | dBm | decibels referenced to one milliwatt | | DBMS | database management system | | DC |
 domain controller | | DCE | Distributed Computing Environment | | DCOM | Distributed Component
 Object Model | | DCS | distributed control system | | DDMS | Department of Defense Metadata
 Specification | | DDoS | distributed denial of service | | DEA | Data Encryption Algorithm | | DEP |
 Data Execution Prevention | | DES |

..... PART 2-DEFINITIONS OF WORDS AND TERMS 3. Amend section 2.101, in paragraph (b)(2) by: a. In the definition of “Component”, removing from the end of paragraph (3) the word “and”; removing from the end of paragraph (4) “52.225-23(a)” and adding “52.225-23(a); and” in its place; and adding a new paragraph (5); b. Removing the definitions “Federally-controlled information system” and “Information and communication technology (ICT)”; c. Adding in alphabetical order the definitions “Federal information system”, “Government data”, “Information”, “Information and communications technology (ICT)”, and “Information system”; d. In the definition of “Information technology”, revising paragraph (3)(ii); and e. Adding in alphabetical order the definitions “Internet of Things (IoT) devices”, “Operational technology”, “Telecommunications equipment”, and “Telecommunications services”. The revisions and additions read as follows: 2.101 Definitions. * * * * * (b) * * * (2) * * * Component * * * * * (5) Subpart 39.X, see the definition in 39.X01. * * * * * Federal information system (1) Means an information system (44 U.S.C. 3502(8)) used or operated by an agency, by a contractor of an agency, or by another organization, on behalf of an agency; (2) On behalf of an agency as used in this definition, means when a contractor uses or operates an information system or maintains or collects information for the purpose of processing, storing, or transmitting Government data, and those activities are not incidental to providing a service or product to the Government (32 CFR part 2002). * * * * * Government data means any information, (including metadata), document, media, or machine-readable material regardless of physical form or characteristics that is created or obtained by the Government, or a contractor on behalf of the Government, in the course of

official Government business. * * * * * Information, as used in subparts 4.19 and 39.X, means any communication or representation of knowledge such as facts, data, or opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, electronic, or audiovisual forms (see Office of Management and Budget (OMB) Circular No. A-130, Managing Information as a Strategic Resource). Information and communications technology (ICT) means information technology and other equipment, systems, technologies, or processes, for which the principal function is the creation, manipulation, storage, display, receipt, or transmission of electronic data and information, as well as any associated content. Examples of ICT include but are not limited to the following: Computers and peripheral equipment; information kiosks and transaction machines; telecommunications equipment; telecommunications services; customer premises equipment; multifunction office machines; computer software; applications; websites; electronic media; electronic documents; Internet of Things (IoT) devices; and operational technology. Information system

nonymously collect and share cybersecurity incident and supply chain data for measurement and metrics analytics and to provide users with educational and informative resources to improve their C-SCRM. - NIST launched the hardware security program to identify existing and emerging cybersecurity threats and develop mitigation techniques for semiconductors, including cybersecurity and supply chain standards, guidelines, and recommended practices in collaboration with the semiconductor community. NIST also hosted a Supply Chain workshop and published NIST IR 8540, Report on Secure Hardware Assurance Reference Dataset Program . - To support data safeguarding, NIST released NIST IR 8432, Cybersecurity of Genomic Data ; SP 1800-28, Data Confidentiality: Identifying and Protecting Assets Against Data Breaches ; SP 180029, Data Confidentiality: Detect, Respond to, and Recover from Data Breaches; and NIST IR 8496, Data Classification Concepts and Considerations for Improving Data Protection . - NIST published SP 1800-38B, Migration to Post-Quantum Cryptography (PQC) Quantum Readiness: Cryptographic Discovery , and SP 1800-38C, Migration to PQC Quantum Readiness: Testing Draft Standards . - NIST published SP 800-231, Bugs Framework (BF): Formalizing Cybersecurity Weaknesses and Vulnerabilities ; SP 800-204D, Strategies for the Integration of Software Supply Chain Security in DevSecOps CI/CD Pipelines ; SP 800-218A, Secure Software Development Practices for Generative AI and Dual-Use Foundation Models : An SSDF Community Profile ; and enhanced the Software Assurance Reference Dataset (SARD) with four test suites from the Static Analysis Tool Exposition (SATE) VI. NIST also improved the AI Bug Finder, and the National Software Reference Database added data from 10,000+ new or updated applications (totaling over 42 million files) to assist with computer security and digital forensics analysis.

multitude of errors and developer pitfalls in the cryptographic implementations of software products [1-5]. However, these studies focused on the practices of less-experienced, individual developers. Therefore, there was little understanding of the cryptographic development practices of organizations, including the benefits and challenges of using cryptographic resources such as standards specifications and libraries.

CIS Safeguard 11.1 · Establish and Maintain a Data Recovery Process Establish and maintain a data recovery process. In the process, address the scope of data recovery activities, recovery prioritization, and the security of backup data. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard. Implementation Groups: 1,2,3 Asset Type: data Security Function: recovery Parent Control: Data Recovery

Removing the clause date of (MAR 2014) and adding (DATE) in its place; c. Redesignating paragraphs (b)(i) through (iii) as (c)(1) through (3), respectively; d. Adding a new paragraph (b); and e. Revising paragraph (c)(1). The addition and revision reads as follows: 252.232-7012 Performance-Based Payments-Whole-Contract Basis. * * * * * (b) In accordance with 10 U.S.C. 2307(b) , the output of the Contractor's accounting system shall be in compliance with Generally Accepted Accounting Principles, as evidenced by audited financial statements, in order to receive performance-based payments. (c)(1) The Contractor shall, in addition to providing the information required by FAR 52.232-32, submit supporting information for all payment requests using the following format: * * * * * 8. Amend section 252.232-7013 by: a. In the clause introductory text, removing 232.1005-70(b) and adding 232.1005-70(a)(2) in its place; b. Removing the clause date of (APR 2014) and adding (DATE) in its place; c. Redesignating paragraphs (b)(i) through (iii) as (c)(1) through (3), respectively; d. Adding a new paragraph (b); and (printed page 18225) e. Revising newly redesignated paragraph (c)(1). The addition and revision read as

follows: 252.232-7013 Performance-Based Payments-Deliverable-Item Basis. * * * * * (b) In accordance with 10 U.S.C. 2307(b), the output of the Contractor's accounting system shall be in compliance with Generally Accepted Accounting Principles, as evidenced by audited financial statements, in order to receive performance-based payments. (c)(1) The Contractor shall, in addition to providing the information required by FAR 52.232-32, submit supporting information for all payment requests using the following format: * * * * * 9. Add section 252.232-70XX to read as follows: 252.232-70XX Performance-Based Payments-Representation As prescribed in 232.1005-70(b), use the following provision: Performance-Based Payments-Representation (DATE) (a) In accordance with 10 U.S.C. 2307(b), the output of a contractor's accounting system shall be in compliance with Generally Accepted Accounting Principles in order to receive performance-based payments. (b) The Offeror represents that the output of its accounting system is [.] is not [.] in compliance with Generally Accepted Accounting Principles, as evidenced by audited financial statements. (End of Provision) [FR Doc. 2019-08487 Filed 4-29-19; 8:45 am] BILLING CODE 5001-06-P

(1) The Contractor shall indemnify the Government and its officers, agents, and employees acting for the Government against any liability arising out of the performance of the contract, including costs and expenses, incurred as the result of the Contractor's unauthorized introduction of copyrighted material to which the Contractor has no rights or license that may infringe on the copyright interest of others, information subject to a right of privacy, and any libelous or other unlawful matter into Government data. The Contractor agrees to waive any and all defenses that may be asserted for its benefit, including (without limitation) the Government Contractors Defense. (2) The Contractor shall indemnify the Government and its officers, agents, and employees acting for the Government against any liability arising out of the performance of this contract, including costs and expenses, (printed page 68422) incurred as the result of the Contractor's potential or actual unauthorized disclosure of trade secrets, copyrighted materials, contractor bid or proposal information, source selection information, classified information, material marked as Controlled Unclassified Information, information subject to a right of privacy or publicity, personally identifiable information as defined by OMB Circular A-130 (2016) or successor thereof, or any record as defined in 5 U.S.C. 552a. (3) In the event of any claim or suit against the Government on account of any alleged unauthorized disclosure or introduction of data or information arising out of the performance of this contract or services performed under this contract, the Contractor shall furnish to the Government, when requested by the Contracting Officer, all evidence and information in the Contractor's possession pertaining to such claim or suit. (4) The provisions of this paragraph (m) do not apply unless the Government provides notice to the Contractor as soon as practicable of any claim or suit, affords the Contractor an opportunity under applicable laws, rules, or regulations to participate in the defense of the claim or suit, and these provisions do not apply to any libelous or other unlawful matter contained in such data furnished to the Contractor by the Government and incorporated in data to which this clause applies. Further, this indemnity shall not apply to: (i) A disclosure or inclusion of data or information upon specific written instructions of the Contracting Officer directing the disclosure or inclusion of such information or data; or (ii) A third-party claim that is unreasonably settled without the consent of the Contractor, unless required by final decree of a court of competent jurisdiction. (n) Subcontracts. The Contractor shall include the substance of this clause, including this paragraph (n), in all subcontracts under this contract for services to develop, implement, operate, or maintain, a FIS using other than cloud computing services. (End of clause) 23. Amend section 52.244-6 by: a.

The Department has also provided guidance that a regulated entity can use to devise its security incident plans. The policies and procedures a regulated entity establishes to prepare for and respond to security incidents can pay dividends with faster recovery times and reduced compromises of ePHI. [593] A well thought-out, well-tested security incident response plan is integral to ensuring the confidentiality, integrity, and availability of a regulated entity's ePHI. A timely response to a security incident can be one of the best ways to prevent, mitigate, and recover from future cyberattacks. For example, responding to a single intrusion or inappropriate access can prevent a pattern of repeated malicious actions. It is extremely important that a regulated entity analyzes an incident to establish what has occurred and its root cause. Doing so will enable the regulated entity to use that information to update its security incident response plans. The Department has previously issued guidance addressing such activities as forming a security incident response team, identifying and responding to security incidents, mitigating harmful effects of and

documenting a security incident, and breach reporting. [594] NIST also offers guidance for addressing security incidents. [595] It describes four key activities with detailed descriptions and sample questions: Determine the goals of an incident response. Develop and deploy an incident response team or other reasonable and appropriate response mechanism. Develop and implement policy and procedures to respond to and report security incidents. Incorporate post-incident analysis into updates and revisions. NIST has also issued comprehensive guidelines for incident handling, particularly for analyzing incident related data and determining the appropriate response to each incident. [596] For example, the NIST Cybersecurity Framework addresses these activities as part of the core function of ·[respond-a]ctions regarding a detected cybersecurity incident are taken.· [597] ·Respond· supports the ability of the regulated entity ·to contain the effects of cybersecurity incidents. Outcomes within this Function [include] incident management, analysis, mitigation, reporting, and communication.· [598] Despite this existing guidance, OCR's enforcement experience indicates that many regulated entities have not met the existing standard, so we believe that additional specificity regarding their obligations and liability for incident response is warranted. Accordingly, the Department proposes to redesignate the standard for security incident procedures as 45 CFR 164.308(a)(12)(i)

Note that agenda items may change without notice because of possible unexpected schedule conflicts of presenters. The final agenda will be posted on the Web site indicated above. Seating will be available for the public and media. No registration is required to attend this meeting. Public Participation: The ISPAB agenda will include a period of time, not to exceed thirty minutes, for oral comments from the public (Friday, February 15, 2013, between 10:00 a.m. and 10:30 a.m.). Speakers will be selected on a first-come, first-served basis. Each speaker will be limited to five minutes. Questions from the public will not be considered during this period. Members of the public who are interested in speaking are requested to contact Annie Sokol at the contact information indicated in the FOR FURTHER INFORMATION CONTACT section of this notice. Speakers who wish to expand upon their oral statements, those who had wished to speak but could not be accommodated on the agenda, and those who were unable to attend in person are invited to submit written statements. In addition, written statements are invited and may be submitted to the ISPAB at any time. All written statements should be directed to the ISPAB Secretariat, Information Technology Laboratory, 100 Bureau Drive, Stop 8930, National Institute of Standards and Technology, Gaithersburg, MD 20899-8930. Dated: December 21, 2012. Willie E. May, Associate Director for Laboratory Programs. [FR Doc. 2012-31525 Filed 12-31-12; 8:45 am] BILLING CODE 3510-13-P

(Comment 155) One comment asks that FDA not disclose personal details (name of responsible person) about secondary suppliers. The comment notes that disclosure of personal details of secondary suppliers might be contrary to international and European privacy regulations. One comment notes that disclosure to the public of the names of the firm and the responsible individual might conflict with foreign confidentiality rules of law. Other comments express concern about protecting personal privacy information. Another comment states that farmers are concerned about the effect of possible information disclosure on the personal and physical security of their farms where they reside with their families. (Response) Foreign persons, except for those who transport food in the United States, are exempt from all of the requirements in subpart J of this final rule. Farms are also exempt. FDA follows Federal statutes (e.g., FOIA, the Privacy Act) and its regulations (e.g., parts 20 and 21) in determining the proper treatment of information it receives, including personal information. FOIA, for example, contains exemptions that allow FDA to withhold personal information from the public in certain circumstances (5 U.S.C. 552(b)(6) and (b)(7)). (Comment 156) A few comments ask what assurances FDA can give to a person subject to the Bioterrorism Act that the information will not be subject to unauthorized disclosure. Other comments ask that CBP and FDA guarantee nondisclosure of the information. A comment asks how FDA can guarantee the confidentiality of confidential and secret information such as formulas. (Response) FDA complies with Federal law (e.g., the FD&C Act, FOIA, Trade Secrets Act) and regulations (e.g., parts 20 and 21) regarding the dissemination of the information it receives. FDA employees are subject to criminal penalties for disclosing information in violation of section 301(j) of the FD&C Act or the Trade Secrets Act. FDA plans to reemphasize to its field personnel the importance of current protections and legal requirements against unauthorized disclosure of any protected information FDA obtains. (Comment 157) A comment concerned about adverse publicity asks with whom might FDA share information. (Response) FDA is authorized to share certain nonpublic information with others. For example, FDA may share confidential commercial information with a sister agency within the (printed page 71609) Department of Health and Human Services, a State government agency official whom FDA has

. In addition, patch management, [924] access control, [925] authentication, [926] and appropriate business associate agreements [927] are examples of some of the required safeguards that would apply to VR and AR systems. We believe the proposals in this NPRM to clarify these safeguards would substantially improve the ability of regulated entities to address these cybersecurity risks. For example, the Department proposes to require that a regulated entity obtains from a business associate written verification that the business associate has deployed the technical safeguards required by the Security Rule, including a written analysis of the business associate's information systems from a person with (printed page 992) appropriate knowledge of and experience with generally accepted cybersecurity principles and methods for ensuring the confidentiality, integrity, and availability of ePHI verifying compliance with the requirements of 45 CFR 164.312 and a written certification that the analysis has been performed and is accurate. Under this proposal, a regulated entity would be required to obtain such verification from a business associate-developer of VR/AR software, ensuring that ePHI that is created, received, maintained, or transmitted using the VR/AR software is protected to the same extent as ePHI that is created, received, maintained, or transmitted using other technology assets that are components of the regulated entity's relevant electronic information systems. Many regulated entities are piloting innovative technologies. Such entities generally have separate departments that research, develop, test, and deploy such technologies. [928] Regulated entities might consider integrating workforce members with expertise in security and privacy into their technology development groups to ensure that privacy and security, including the Security Rule-required safeguards, are embedded into the design of new and emerging technologies. [929] Doing so can help improve security while boosting quality, efficiency, and productivity. [930]

4. Request for Comment The Department requests comment on the foregoing discussion of how the Security Rule protects ePHI used in new and developing technologies, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular:

- a. Whether the Department's understanding of how the Security Rule applies to new technologies involving ePHI is not comprehensive and if so, what issues should also be considered.
- b. Whether there are technologies that currently or in the future may harm the security and privacy of ePHI in ways that the Security Rule could not mitigate without modification, and if so, what modifications would be required.
- c. Whether there are additional policy or technical tools that the Department may use to address the security of ePHI in new technologies.

V. Regulatory Impact Analysis A. Executive Order 12866 and Related Executive Orders on Regulatory Review

(2) Nothing in the amendment process is intended or designed to permit a collateral attack upon what has already been the subject of a judicial or quasi-judicial determination. However, while the individual may not attack the accuracy of the judicial or quasi-judicial determination under this part, he or she may challenge the accuracy of the recording of that action.

(f) Sufficiency of a request to amend. Consider the following factors when evaluating the sufficiency of a request to amend: (1) The accuracy of the information; and (2) The relevancy, timeliness, completeness, and necessity of the recorded information.

(g) Time limits. (1) Provide written acknowledgement of a request to amend within 10 working days of its receipt by the appropriate systems manager. There is no need to acknowledge a request if the action is completed within 10 working days and the individual is so informed. (2) The letter of acknowledgement shall clearly identify the request and advise the individual when he or she may expect to be notified of the completed action. (3) Only under the most exceptional circumstances shall more than 30 days be required to reach a decision on a request to amend. Document fully and explain in the Privacy Act case file (see paragraph (p) of this section) any such decision that takes more than 30 days to resolve.

(h) Agreement to amend. If the decision is made to grant all or part of the request for amendment, amend the record accordingly and notify the requester.

(i) Notification of previous recipients. (1) Notify all previous recipients of the record, as reflected in the disclosure accounting records, that an amendment has been made and the substance of the amendment. Recipients who are known to be no longer retaining the information need not be advised of the amendment. All DoD Components and Federal agencies known to be retaining the record or information, even if not reflected in a disclosure record, shall be notified of the amendment. Advise the requester of these notifications. (2) Honor all requests by the requester to notify specific Federal agencies of the amendment action.

(j) Denying amendment. If the request for amendment is denied in whole or in part, promptly advise the individual in writing of the decision to include: (1) The specific reason and authority for not amending; (2) Notification that he or she may seek further independent review of the decision by

the Head of the DoD Component or his or her designee; (3) The procedures for appealing the decision citing the position and address of the official to whom the appeal shall be addressed; and (4) Where he or she can receive assistance in filing the appeal. (k) DoD Component appeal procedures. Establish procedures to ensure the prompt, complete, and independent review of each amendment denial upon appeal by the individual. These procedures must ensure:

This publication, Volume 4 of NISTIR 8011, immediately follows Hardware Asset Management (HWAM) and Software Asset Management (SWAM) capabilities published as Volumes 2 and 3 respectively. Although it was planned to be released as Volume 5, following Configuration Settings Management (CSM), the VUL capability is being addressed as Volume 4 in the NISTIR 8011 series due to its close relationship with software. Its objective is to address the management of risk created by defects present in software on the network. A software vulnerability is caused by one or more known defects that have been discovered in software, and that can be exploited to affect an adverse security or privacy outcome. 1 Vulnerable software is software in use on a system that has a software vulnerability but has not yet been patched or otherwise mitigated. The Common Weakness Enumeration (CWE) provides identifiers for weaknesses that result from poor design or coding practices and have the potential to result in software vulnerabilities. The Common Vulnerabilities and Exposures (CVEs) program works with software providers, vulnerability coordinators, bug bounty programs, and vulnerability researchers to provide a list of publicly disclosed vulnerabilities. Together, CVE and CWE are used to identify software defects and the weaknesses that caused a given defect respectively. Vulnerable software is a key target that attackers use to initiate an attack and to expand control within a system. Patching vulnerabilities discovered in existing software and improving coding practices for future releases of software are two ways to limit the success of attacks. 2 Derived from the Control Allocation Tables (CAT) in this volume. With respect to security controls selected in the NIST SP 800-53 [SP800-53] Low-Medium-High baselines that support the VUL capability, 42 of 48 determination statements (87.5 %) can be fully or partially automated. Medium-High baselines can be fully or partially automated.

Identifying the CMMC Assessment Scope CMMC Assessment Scope · Level 3 · Version 2.13 4 Asset Category Asset Description OSC Requirements CMMC Assessment Requirements Out-of-Scope Assets o Assets that cannot process, store, or transmit CUI; and do not provide security protections for CUI Assets o Assets that are physically or logically separated from CUI assets o Assets that fall into any in-scope asset category cannot be considered an Out-of-Scope Asset o An endpoint hosting a VDI client configured to not allow any processing, storage, or transmission of CUI beyond the Keyboard/Video/Mouse sent to the VDI client is considered an Out-of-Scope Asset o Prepare to justify the inability of an Out-of-Scope Asset to store, process, or transmit CUI o None

Notably, government and private industry CSRM and ERM programs have different oversight and reporting requirements (e.g., accountability to the public versus accountability to shareholders), but the general needs and processes are quite similar. The risk register provides an easily consumed summary for understanding the risk landscape, but effective risk communication requires many additional details that would not fit into this compact table. The additional information should be recorded in a Risk Detail Record (RDR) and be readily available should the additional detail be required about a risk register entry. The RDR provides an opportunity to record historical risk-related information, detailed risk analysis data, and information about individual and organizational accountability. Appendix B of this document provides a notional example of such a record. Risk appetite and risk tolerance are related but distinct in a similar manner to the relationship between governance and management activities. Where risk appetite statements define the overarching risk guidance, risk tolerance statements define the specific application of that direction. This means risk tolerance statements are always more specific than the corresponding risk appetite statements. Together, these risk appetite and risk tolerance statements represent risk limits, help communicate risk expectations, and improve the focus of risk management efforts. They also help to address other factors such as findings from internal audits or external reports (e.g., an examination of corporate financial records by an independent audit firm, a review of a federal agency's improved IT management through the Federal Information Technology Acquisition Reform Act [FITARA]). The definition of these risk parameters places the enterprise in a better position to identify, prioritize, treat, and monitor risks that may lead to unacceptable loss.

In addition, in the course of carrying out analysis for insider threats, exempt records from other

systems of records may in turn become part of the case records maintained in this system. To the extent that copies of exempt records from those other systems of records are maintained into this system, the DoD claims the same exemptions for the records from those other systems that are entered into this system, as claimed for the original primary system of which they are a part. (2) System identifier and name. DUSDI 02-DoD ·Personnel Vetting Records System.· (i) Exemption. This system of records is exempted from subsections 5 U.S.C. 552a(c)(3) , (d)(1), (d)(2), (d)(3), (d)(4), and (e)(1) of the Privacy Act. (ii) Authority. 5 U.S.C. 552a(k)(1) , (k)(2), (k)(3), (k)(5), (k)(6), and (k)(7). (iii) Exemption from the particular subsections. Exemption from the particular subsections is justified for the following reasons: (A) Subsections (c)(3), (d)(1), and (d)(2) . (1) Exemption (k)(1). Personnel investigations and vetting records may contain information properly classified pursuant to Executive Order. Application of exemption (k)(1) for such records may be necessary because access to, amendment of, or release of the accounting of disclosures of such records could disclose classified information that could be detrimental to national security. (2) Exemption (k)(2). Personnel investigations and vetting records may contain investigatory material compiled for law enforcement purposes other than material within the scope of 5 U.S.C. 552a(j)(2) . Application of exemption (k)(2) for such records may be necessary because access to, amendment of, or release of the accounting of disclosures of such records could: Inform the record subject of an investigation of the existence, nature, or scope of an actual or potential law enforcement or counterintelligence investigation, and thereby seriously impede law enforcement or counterintelligence efforts by permitting the record subject and other persons to whom he might disclose the records to avoid criminal penalties, civil remedies, or counterintelligence measures; interfere with a civil or administrative action or investigation which may impede those actions or investigations; and result in an unwarranted invasion of the privacy of others. Amendment of such records could also impose a highly impracticable administrative burden by requiring investigations to be continuously reinvestigated. (3) Exemption (k)(3). Personnel investigations and vetting records may contain information pertaining to providing protective services to the President of the United States or other individuals pursuant to 18 U.S.C. 3056 . Application of exemption (k)(3) for such records may be necessary because access to, amendment of, or release of the accounting of disclosures of such records could compromise the safety of the individuals protected pursuant to 18 U.S.C. 3056

If you are a nontransporter, you must retain for 1 year after the dates you receive and release the food all required records for any food for which a significant risk of spoilage, loss of value, or loss of palatability occurs only after a minimum of 60 days, but within 6 months, after the date you receive or release the food. If you are a nontransporter, you must retain for 2 years after the dates you receive and release the food all required records for any food for which a significant risk of spoilage, loss of value, or loss of palatability does not occur sooner than 6 months after the date you receive or release the food, including foods preserved by freezing, dehydrating, or being placed in a hermetically sealed container. If you are a nontransporter, you must retain for 1 year after the dates you receive and release the food all required records for animal food, including pet food. Transporters of food (or specified persons who agree to establish and maintain required records under agreements with transporters) in the United States must retain records for 6 months for any food having a significant risk of spoilage, loss of value, or loss of palatability within 60 days after the date the transporter receives or releases the food. Transporters of food (or specified persons who agree to establish and maintain required records under agreements with transporters) in the United States must retain records for 1 year for any food having a significant risk of spoilage, loss of value, or loss of palatability only after a minimum of 60 days after the date the transporter receives or releases the food. Records must be made available as soon as possible, not to exceed 24 hours from the time of receipt of the official request. Failure to establish or maintain records or refusal to permit access to or verification or copying of any record is a prohibited act under section 301 of the FD&C Act. The compliance date for the records establishment and maintenance requirements is December 9, 2005, except that the compliance date for small businesses employing fewer than 500, but more than 10 full-time equivalent employees is June 9, 2005, and the compliance date for very small businesses that employ 10 or fewer full-time equivalent employees is December 11, 2006. B. Significant Changes FDA Made to the Proposed Rule FDA made the following significant changes to the proposed rule: All foreign persons, except foreign persons who transport food in the United States, are excluded from all of the requirements in subpart J of this final rule. A foreign person transporting food in the United States is subject to the requirements for transporters in the subpart.

The DoD reserves the right to decide when reliance on self-assessment will suffice, and when compliance should be assessed through CMMC certification. Based on DoD decision criteria that includes a risk assessment of the type and sensitivity of program information to be shared, Program Managers will identify the appropriate CMMC requirement (e.g., CMMC Level 2 self-assessment or Level 2 certification) in the solicitation. The government does not have the capacity in house to adequately assess (printed page 83159) the 220,00+ companies in the DIB. The DoD cannot assume the workload of directly assessing every DIB contractor. With this final rule, DoD established a scalable way to verify, through assessment, that contractors have implemented required security measures necessary to safeguard DoD information. The DIBCAC's mission is derived from DoD priorities and the Department is actively working to ensure that the DIBCAC is adequately resourced to effectively execute its mission areas. Planned changes to DCMA staffing levels have been considered and are necessary to implement the elements of the CMMC program described in this rule (i.e., Level 3 and C3PAO assessments). By design, the CMMC Program depends on the supply and demand dynamics of the free market, enabling it to naturally scale and adapt to capacity requirements. The DoD established requirements for each part of the CMMC ecosystem to support a robust compliance assessment mechanism for DoD's contractual requirements to safeguard CUI that is processed, stored, or transmitted in contractor owned information systems. The DoD cannot assume the workload of directly assessing every DIB contractor. One commenter provided numerous comments expressing concern that OSAs that use ESPs will be unlikely to know which ESP services require CMMC assessment within the OSAs boundary or scope. This commenter recommended an alternate type of CMMC assessment specifically for ESPs. In lieu of adopting that recommendation, the DoD has updated the rule in §§ 170.19(c)(2) and (d)(2) to reduce the assessment burden on ESPs. DoD declined to allow partial CMMC Assessments. ESPs may request voluntary CMMC assessments of their environment and use that as a business discriminator. The marketplace for ESP services will adjust to find the efficient manner for ESPs to support OSA assessments. e. Alternate Governance Comment:

3.2.6 ||| Develop and disseminate a security policy that provides an overview of the security requirements for the manufacturing system. 3.2.6.

The Administrative Simplification provisions of HIPAA instructed the Secretary to adopt several standards concerning electronic transmission of health information, including those for the security of health information. [69] In accordance with these provisions, the Department published the Security and Electronic Signature Standards; Proposed Rule (·1998 Proposed Rule·) on August 12, 1998. [70] In support of developing the national standards mandated under HIPAA's Administrative Simplification provisions, the Secretary, with significant input from the health care industry, defined a set of principles for guiding choices for the standards to be adopted by the Secretary. [71] The principles were based on direct specifications in HIPAA and also took the purpose of the law and generally desirable principles into account. Based on this work, the Department proposed that each HIPAA standard should be clear and unambiguous but technology neutral, improve the efficiency and effectiveness of the health care system, meet the needs of covered entities related to ease of use and affordability of adoption, and maintain consistency or alignment with other HIPAA standards adopted by an organization accredited by the American National Standards Institute (ANSI) and using the ANSI process for adopting such standards. [72] In describing its general approach to the 1998 Proposed Rule, the Department defined the security standard as a set of requirements with implementation features that covered entities must include in their operations to assure the security of individuals' ePHI. [73] The security standard was based on three basic concepts that were derived from the Administrative Simplification provisions of HIPAA and consistent with the characteristics the Department identified as appropriate for all HIPAA Rules. [74] First, the standard should be comprehensive and coordinated to address all aspects of security. Second, it should be scalable, so that it could be effectively implemented by covered entities of all types and sizes. Third, it should not be linked to specific technologies, allowing covered entities the flexibility to make use of future technology advancements. [75] The 1998 Proposed Rule included four categories of requirements that a covered entity would have to address to safeguard the confidentiality, integrity, and availability of ePHI. They were as follows: Administrative procedures. Physical safeguards. Technical security services. Technical mechanisms. The implementation specifications described some of the requirements in greater detail, based on our determination regarding the level of instruction necessary to implement such requirements. [76] The Department viewed all categories as equally important. [77] The proposed standard did not address the extent to which a covered entity should implement the specifications. [78]

(C) From subsection (e)(1) because it is not always possible to determine what information is relevant and necessary at an early stage in a given investigation. Also, because Pentagon Force Protection Agency and other agencies may not always know what information about a known or suspected offender may be relevant to for the purpose of conducting an operational response. (D) From subsections (e)(4)(G) through (I) (Agency Requirements) because portions of this system are exempt from the access and amendment provisions of subsection (d). (E) From subsection (f) because requiring the Agency to grant access to records and establishing agency rules for amendment of records would compromise the existence of any criminal, civil, or administrative enforcement activity. To require the confirmation or denial of the existence of a record pertaining to a requesting individual may in itself provide an answer to that individual relating to the existence of an on-going investigation. Counterintelligence investigations would be jeopardized by agency rules requiring verification of the record, disclosure of the record to the subject, and record amendment procedures. (26) System identifier and name. DMDC 16 DoD, Identity Management Engine for Security and Analysis (IMESA). (i) Exemption. To the extent that copies of exempt records from JUSTICE/FBI-001, National Crime Information Center (NCIC) are entered into the Interoperability Layer Service records, the OSD hereby claims the same exemptions, (j)(2) and (k)(3), for the records as claimed in JUSTICE/FBI- 001, National Crime Information Center (NCIC). Pursuant to 5 U.S.C. 552a portions of this system that fall within (j)(2) and (k)(3) are exempt from the following provisions of 5 U.S.C. 552a , section (c)(3) and (4); (d); (e)(1) through (3); (e)(4)(G) through (I); (e)(5) and (8); (f); and (g) (as applicable) of the Act. (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(3) . (iii) Reasons. (A) From subsection (c)(3) because making available to a record subject the accounting of disclosure from records concerning him or her would specifically reveal any investigative interest in the individual. Revealing this information could reasonably be expected to compromise ongoing efforts to investigate a known or suspected terrorist by notifying the record subject that he or she is under investigation. This information could also permit the record subject to take measures to impede the investigation, e.g. destroy evidence, intimidate potential witnesses, or flee the area to avoid or impede the investigation. (B) From subsection (c)(4) because portions of this system are exempt from the access and amendment provisions of subsection (d).

It is also possible that the commenter interpreted that a Level 2 self-assessment is adequate for subcontractors working with a prime that has a contractual requirement for a Level 3 certification assessment. In this case, a CMMC Status of Final Level 2 (Self) is not adequate. A CMMC Status of Final Level 3 (DIBCAC) signifies that the prime first achieved a CMMC Status of Final Level 2 (C3PAO) as the risk to their CUI was deemed high enough to require Level 2 certification assessment. Since this same information may be shared with subcontractors who process, store, or transmit CUI, the subcontractor must also achieve CMMC Status of Final Level 2 (C3PAO). The decision to rely upon a CMMC Level 2 self-assessment in lieu of a certification assessment is a Government risk-based decision based upon the nature of the effort to be performed and CUI to be shared. The size of the company with access to the CUI is not a basis for this determination. The value of information and impact of its loss does not diminish when the information moves to contractors of smaller size. 4. Assessment. Commenters questioned whether CMMC will accept reciprocity with other compliance methodologies. Another questioned what would drive a company to seek a reassessment of their environment. Other commenters suggested that we allow small businesses 365 days to close their POA&M requirements, as well as suggesting that pre-assessment materials do not need to be uploaded into eMASS, and that the hashing requirements should be simplified. Other suggestions made were to allow Program Managers to relax requirements based on a risk decision and allow assessors to make judgement calls on what evidence constitutes compliance with the requirement. One commenter requested the DoD publish an overview of the assessment methodology that includes the defined frequency guidelines. Additionally, one commenter requested that access to Procurement Integrated Enterprise Environment (PIEE) and Supplier Performance Risk System (SPRS) be made easier for small contractors. DoD Response: CMMC requirements apply to DoD contracts, and not to contracts issued by other agencies. Flow down of CMMC requirements from a prime contractor to its subcontractors shall apply, as addressed in § 170.23(a) of this rule. DoD intends to allow qualified standards acceptance of a DIBCAC High Assessment using NIST SP 800-171 R2 for CMMC Status of Final Level 2 (C3PAO) as addressed in § 170.20.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this

publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The Special Publication 800-series reports on ITL's research, guidelines, and outreach efforts in information system security, and its collaborative activities with industry, government, and academic organizations. This publication describes an approach for the development of Information Security Continuous Monitoring (ISCM) program assessments that can be used to evaluate ISCM programs within federal, state, and local governmental organizations and commercial enterprises.

(Comment 76) Many comments suggest that caterers supplying interstate conveyances are preparing meals for direct consumption by the consumer and should be excluded as restaurants. Some comments state that the manufacturer/processor of a sandwich should be treated the same, whether the sandwich is served in a restaurant, offered for sale in a vending machine, delivered as carryout, served on a hospital patient's tray, or served on a train or airplane. The comments note that, in the past, FDA has referred to "level playing fields." In this case, exempting of conveyance caterers is the only way to regulate even-handedly. If restaurants and retailers are to be exempt, these comments believe that caterers should also be exempt. The comments further state that just because FDA has historically inspected the facilities providing food to interstate conveyances under the Public Health Service Act does not mean that these facilities should be considered processors under this security regulation. The comments view the proposed distinction between a snack bar on the train selling sandwiches to consumers for immediate consumption (considered an exempted restaurant) and a facility that provides the sandwiches to an airplane or train for later consumption (considered a covered processing establishment) as an arbitrary and illogical distinction, because they view the risk associated with that sandwich as the same between the two facilities. The comments view their industry as similar to a large restaurant or hotel kitchen, which produces a wide variety of meals within a matter of hours. The comments state that inflight catering is not regulated under the same rules as a food processing plant because the same rules would not fit the inflight catering industry. Food in a processing plant may be prepared weeks to a year before consumption. The comments state that the only difference between the catering and the restaurant service is that the catering meals are generally consumed 1 to 4 hours after departing from the kitchen rather than immediately consumed, as in the restaurant industry.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 1. Introduction 173 Executive Order (EO) 13556 [1] established a government-wide program to standardize how the executive branch handles Controlled Unclassified Information (CUI).¹ CUI is any information that a law, regulation, or government-wide policy requires to have safeguarding or dissemination controls, excluding information that is classified under EO 13526 [2], or any predecessor or successor order, or the Atomic Energy Act [3] as amended. EO 13556 required that the CUI program emphasize government-wide openness, transparency, and uniformity and that the program implementation take place in a manner consistent with Office of Management and Budget (OMB) policies a

Data controls. Maintenance. Encryption and decryption 164.312(b) Implementation specification. Exceptions. Alternative measures. Compensating controls. Maintenance. Configuration management 164.312(c) Anti-malware protection. Software removal. Configuration. Network ports. Maintenance. Audit trail and system log controls 164.312(d) Monitor and identify. Record. Retain. Scope. Maintenance. Integrity 164.312(e) Authentication 164.312(f) Information access management policies. Multi-factor authentication. Exceptions. Alternative measures. Compensating controls. Maintenance. Transmission security 164.312(g) Vulnerability management 164.312(h) Vulnerability scanning. Monitoring. Penetration testing. Patch and update installation. Data backup and recovery 164.312(i) Data backup Monitor and identify. Record. Testing. Information

systems backup and recovery 164.312(j) Dated: December 20, 2024. Xavier Becerra, Secretary, Department of Health and Human Services. Footnotes 1. Subtitle F of title II of HIPAA (Pub. L. 104-191 , 110 Stat. 1936 (Aug. 21, 1996)) added a new part C to title XI of the Social Security Act of 1935 (SSA), Public Law 74-271, 49 Stat. 620 (Aug. 14, 1935), (see sections 1171-1179 of the SSA (codified at 42 U.S.C. 1320d-1320d-8)), as well as promulgating section 264 of HIPAA (codified at 42 U.S.C. 1320d-2 note), which authorizes the Secretary to promulgate regulations with respect to the privacy of individually identifiable health information. The Privacy Rule has subsequently been amended pursuant to the Genetic Information Nondiscrimination Act of 2008, title I, section 105, Public Law 110-233 , 122 Stat. 881 (May 21, 2008) (codified at 42 U.S.C. 2000ff), and the Health Information Technology for Economic and Clinical Health (HITECH) Act of 2009, Public Law 111-5 , 123 Stat. 226 (Feb. 17, 2009) (codified at 42 U.S.C. 139w-4(0)(2)). Back to Citation 2. 45 CFR part 160 subparts A and C of 45 CFR part 164 . For a history of the Security Rule, see section II.B, Regulatory History. Back to Citation 3. See also the HIPAA Privacy Rule, 45 CFR part 160 and subparts A and E of 45 CFR part 164 ; HIPAA Breach Notification Rule, 45 CFR part 164, subpart D ; and the HIPAA Enforcement Rule, 45 CFR part 160, subparts C through E . Back to Citation 4. 45 CFR 160.103 (definition of Protected health information-). Back to Citation 5. 45 CFR 160.103 (definition of Individually identifiable health information-). Back to Citation

by adding paragraph (b)(2), which provides that performance-based payments shall not be conditioned upon costs incurred in contract performance but only on the achievement of negotiated performance outcomes. Therefore, this rule proposes to remove the restrictions at DFARS 232.1001(a) and paragraph (b)(i) of the clauses at DFARS 252.232-7012 and 252.232-7013 that limit performance-based payments to amounts not greater than costs incurred up to the time of payment. However, the requirement for contractors to report costs incurred when requesting performance-based payments is retained, in order to have the data necessary for negotiation of performance-based payments on future contracts. Section 831 also added paragraph (b)(3) to 10 U.S.C. 2307 , which addresses the eligibility for performance-based payments of nontraditional defense contractors and other private sector companies. This has been added to the policy at DFARS 232.1001. 10 U.S.C. 2307(b)(4) , as added by section 831, requires contractors to be in compliance with Generally Accepted Accounting Principles in order to receive performance-based payments, with no requirement for a Government-unique accounting systems or practices as a prerequisite to receive performance-based payments. This requirement has been incorporated at DFARS 232.1003-70 and the clauses at DFARS 252.232-7012 and 252.232-7013. This rule also proposes a new representation by each offeror, if performance-based payments are anticipated, as to whether the output of its accounting system is in compliance with Generally Accepted (printed page 18222) Accounting Principles, as evidenced by audited financial statements. III. Applicability to Contracts at or Below the Simplified Acquisition Threshold and for Commercial Items, Including Commercially Available Off-the-Shelf Items This rule proposes to amend the clauses at DFARS 252.232-7012 and 252.232-7013. These clauses do not apply to contracts at or below the simplified acquisition threshold or for the acquisition of commercial items. In accordance with 10 U.S.C. 2307(f) and 41 U.S.C. 4505 , FAR 32.201 provides that payment for commercial items may be made under such terms and conditions as the agency head determines are appropriate or customary in the commercial marketplace and are in the best interest of the United States. Furthermore, FAR 32.202-1 states that Government financing of commercial purchases is expected to be different from that used for noncommercial purchases. While the contracting officer may adapt techniques and procedures from the noncommercial subparts for use in implementing commercial contract financing arrangements, the contracting officer must have a full understanding of effects of the differing contract environments and of what is needed to protect the interests of the Government in commercial contract financing. IV. Expected Cost Impact

means a visit during which a visitor will require, or is expected to require, access to classified information. Classifier means any person who makes a classification determination and applies a classification category to information or material. The determination may be an original classification action or it may be a derivative classification action. Contractors make derivative classification determinations based on classified source material, a security classification guide, or a contract security classification specification, or equivalent. Cleared commercial carrier means a carrier that is authorized by law, regulatory body, or regulation to transport SECRET and CONFIDENTIAL material and has been granted a SECRET facility clearance in accordance with the NISP. Cleared employees means all employees of industrial or commercial contractors, licensees, certificate holders, or grantees of an agency, as well as all employees of subcontractors and

personal services contractor personnel, and who are granted favorable eligibility determinations for access to classified information by a CSA or are being processed for eligibility determinations for access to classified information by a CSA. A contractor may give an employee access to classified information in accordance with the provisions of § 117.10(a)(1)(iii). Closed area means an area that meets the requirements of this rule for safeguarding classified material that, because of its size, nature, or operational necessity, cannot be adequately protected by the normal safeguards or stored during nonworking hours in approved containers. CNWDI means a DoD category of TOP SECRET RD or SECRET RD information that reveals the theory of operation or design of the components of a thermonuclear or fission bomb, warhead, demolition munition, or test device. Specifically excluded is information concerning arming, fusing, and firing systems; limited life components; and total contained quantities of fissionable, fusionable, and high explosive materials by type. Among these excluded items are the components that DoD personnel set, maintain, operate, test or replace. Compromise means an unauthorized disclosure of classified information. COMSEC means the protective measures taken to deny unauthorized persons information derived from USG telecommunications relating to national security and to ensure the authenticity of such communications. CONFIDENTIAL means the classification level applied to information, the unauthorized disclosure of which reasonably could be expected to cause damage to the national security that the original classification authority (OCA) is able to identify or describe. Consignee means a person, firm, or Government (i.e., USG or foreign government) activity named as the receiver of a shipment; one to whom a shipment is consigned. Consignor means a person, firm, or Government (i.e., USG or foreign government) activity by which articles are shipped. The consignor is usually the shipper. Constant surveillance service

45 CFR 164.312(c)(2)(ii) and (iv) . The Department estimates that 629,796 establishments are owned by small and medium-sized covered entities, [963] which is approximately 76.56 percent of all covered entities [= 629,796/822,600]. The Department applies that percentage to the estimated number of business associates [= $0.7656 \times 1,000,000$] to arrive at the estimated number of regulated entities with quantifiably increased burdens from these proposed requirements to disable unused ports and remove extraneous software. We estimate that for these 1,395,396 regulated entities [= 629,796 covered entities + 765,600 business associates], an average annual burden of 30 minutes would be needed at the wage rate of an information security analyst to make needed changes to configuration management, specifically disabling unused ports and removing extraneous software. This would result in estimated total cost increases of \$83,681,898 [= $1,395,396 \text{ regulated entities} \times 0.5 \text{ hours} \times \119.94], with a low estimate of \$41,840,949 [= $1,395,396 \text{ regulated entities} \times 0.25 \text{ hours} \times \119.94] based on an estimated annual burden of 15 minutes per affected entity and a high estimate of \$109,301,322 [= $1,822,600 \text{ regulated entities} \times 0.50 \text{ hours} \times \119.94] based on an estimated annual burden of 30 minutes for all regulated entities. h. Costs Related to Regulated Entities Conducting Penetration Testing The Department estimates that each regulated entity would spend an average of 3 hours conducting penetration testing (with a low estimate of 2 hours and a high estimate of 10 hours) at the hourly wage of an information security analyst. The Department expects that there might be a high degree of variability between entities depending on their size and technological sophistication. Large entities have more endpoints to test, and thus have greater exposure. The Department also believes there is room for significant variability in the effort that regulated entities may apply to this activity. At the wage rate of an information security analyst, this would result in estimated total annual costs for regulated entities of \$655,807,932 [= $1,822,600 \text{ regulated entities} \times 3 \text{ hours} \times \119.94], with a low estimated total of \$437,205,288 [= $1,822,600 \text{ regulated entities} \times 2 \text{ hours} \times \119.94] and high estimated total of \$2,186,026,440 [= $1,822,600 \text{ regulated entities} \times 10 \text{ hours} \times \119.94]. i. Costs Arising From Reporting Contingency Plan Activation The Department estimates that business associates would need to notify other regulated entities in the event that they activate their contingency plan once business associate agreements are revised according to proposed 45 CFR 164.314(a)(2)(i)(D)

for a CSA to review and make a determination whether the entity is under foreign ownership, control or influence (FOCI) to a degree that renders it ineligible for an FCL. The CSA will consider a U.S. entity to be under FOCI when a foreign interest has the power to direct or decide issues affecting the entity's management or operations in a manner that could either result in unauthorized access to classified information; or adversely affect performance of a classified contract or agreement. The U.S. entity may also be considered to be under FOCI when a foreign interest or government is currently exercising, or could exercise, that power, whether directly or indirectly, such as through ownership of the U.S. entity's securities, by contractual arrangements, or other means. Further, if

a foreign interest or government has the ability to control or influence the election or appointment of members of the entity's governing board, the entity may be considered to be under FOCl. When a CSA has determined that an entity is under FOCl, the primary consideration will be the protection of classified information. The CSA will take whatever action is necessary to protect classified information, in coordination with other affected agencies as appropriate. A U.S. entity that is in process for an FCL for access to classified information and subsequently determined to be under FOCl, is ineligible for access to classified information unless and until effective security measures have been put in place to negate or mitigate FOCl to the satisfaction of the CSA. Once an entity becomes a contractor in the NISP with an existing FCL, a GCA can select and award a classified contract to the entity as part of the acquisition process. The GCA attaches the Contract Security Classification Specification: (e.g., for DoD, it is the DD Form 254, available at <https://www.esd.whs.mil/Portals/54/Documents/DD/forms/dd/dd0254.pdf> and available at <https://www.dcsa.mil/is/nccs/>), to all such contracts requiring access to classified information.

II. SEAD 3 Requirements and the NISPOM In 2008, with the publication of E.O. 13467, Reforming Processes Related to Suitability for Government Employment, Fitness for Contractor Employees, and Eligibility for Access to Classified National Security Information (available at <https://obamawhitehouse.archives.gov/the-press-office/2016/09/29/executive-order-amending-executive-order-13467-establish-roles-and>), the DNI was assigned the role of the Security Executive Agent (SecEA), for the development, implementation, and oversight of effective, efficient, and uniform policies and procedures governing the conduct of investigations and adjudications for eligibility for access to classified information and eligibility to hold a sensitive position. In December 2016, the SecEA issued SEAD 3, Reporting Requirements for Personnel with Access to Classified Information or Who Hold a Sensitive Position (available at

Use of insecure cryptography: Use of weak or insecure cryptographic algorithms or key generation methods could allow cryptanalytic or brute-force attacks to recover private keys or obtain fraudulent certificates. Future developments, such as new cryptanalysis, implementation vulnerabilities, or the development of a cryptographically-significant quantum computer, could render a previously-deployed system insecure. Use strong cryptography: Use a well-designed, tested, and maintained cryptographic library, and choose NIST-approved algorithms for hashing and signing.

(1) The access provisions of this part are intended for use by individuals whose records are maintained in a Privacy Act system of records. If a representative acts on their behalf, a written authorization must be provided, with the exception of members of Congress acting on behalf of a constituent. (2) A Department of the Army Blanket Routine Use allows the release of Privacy Act protected information to members of Congress when they are acting on behalf of the constituent and the information is filed and retrieved by the constituent's name or personal identifier. The said Blanket Routine Use is listed below. Congressional Inquiries Disclosure Routine Use: Disclosure from a system of records maintained by a DOD Component may be made to a congressional office from the record of an individual in response to an inquiry from the congressional office made at the request of that individual. (3) Upon a written request, an individual will be granted access to information pertaining to him or her that is maintained in a Privacy Act system of records, unless-

(i) The information is subject to an exemption, the system manager has invoked the exemption, and the exemption is published in the Federal Register ; or (ii) The information was compiled in reasonable anticipation of a civil action or proceeding. (4) Legal guardians or parents acting on behalf of a minor child have the minor child's rights of access under this part, unless the records were created or maintained pursuant to circumstances where the interests of the minor child were adverse to the interests of the legal guardian or parent. (5) These provisions should allow for the maximum release of information consistent with Army and DOD's statutory responsibilities. (b) Individual requests for access. (1) Individuals will address requests for access to records in a Privacy Act system of records to the system manager or the custodian of the record designated in DA systems of records notices (See DA PAM 25-51 or the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy>). (2) Individuals do not have to state a reason or justify the need to gain access to records under the Act. (3) Release of personal information to individuals under this section is not considered a public release of information. (c) Verification of identity for first party requesters. (1) Before granting access to personal data, an individual will provide reasonable verification of identity. (2) When requesting records in writing, the preferred method of verifying identity is the submission of a notarized signature. An alternative method of verifying identity for individuals who do not have access to notary services is the submission of an un-sworn declaration in accordance with 28 U.S.C. 1746 in the following

format: (i) If executed within the United States, its territories, possessions, or commonwealths:
·I declare (or certify, (printed page 46058)

A process to develop a Federal Information Processing Standard (FIPS) for an Advanced Encryption Standard (AES) specifying an Advanced Encryption Algorithm (AEA) has been initiated by the National Institute of Standards and Technology (NIST). In the Fall of 1998, NIST announced fifteen publicly submitted algorithms as candidates for the AES, and invites public review, comment, and analysis in order to narrow the field of candidates to (approximately) five or fewer finalists. During the Round 1 technical evaluation period, these fifteen candidates were subjected to extensive analysis and testing by the cryptographic community. At the conclusion of Round 1, NIST took the following information into consideration: (1) The submitted (official) versions of the AES candidate algorithms, (2) Round 1 public comments, (3) papers and discussions at the Second AES Candidate Conference, (4) results of NIST efficiency and statistical analysis, and (5) other relevant data (e.g., presentations at the Sixth Fast Software Encryption Workshop, discussions on NIST's AES Electronic Discussion Forum, etc.). Using this information, NIST has selected the AES finalist candidate algorithms ("finalists"), which will be subjected to further analysis during Round 2 of the AES development effort. A list of the finalists, along with specifications and intellectual property information, is available at the AES home page, <http://www.nist.gov/aes>. This notice announces the beginning of the Round 2 technical evaluation period for the AES finalists. Additionally, the notice solicits comments on the finalists from the general public, academic and research communities, manufacturers, voluntary standards organizations, and Federal, state, and local government organizations. NIST will use these comments to select one or more of the finalists for inclusion in a draft Federal Information Processing Standards Publication (FIPS PUB), on which public comments will be invited via a future Federal Register announcement. NIST's goal is that the AES will specify one or more unclassified, publicly disclosed encryption algorithm(s) available royalty-free worldwide that is (are) capable of protecting sensitive government information well into the next century.

A sanction policy that clearly communicates a regulated entity's expectations should ensure that workforce members understand their individual compliance obligations and consequences of noncompliance. Regulated entities have the flexibility to implement the standard in a manner consistent with numerous factors, including but not limited to their size, degree of risk, and environment. The HIPAA Rules do not require regulated entities to impose any specific penalty for any particular violation, nor do they require regulated entities to implement any particular methodology for sanctioning workforce members. Rather, in any particular case, each regulated entity must determine the type, cause, and severity of sanctions imposed based upon its policies and the relative severity of the violation. [515] A regulated entity may structure its sanction policies in the manner most suitable to its organization. As described in previously issued guidance materials from the Department and NIST, regulated entities should consider the following when drafting or revising their sanction policies: Documenting or implementing sanction policies pursuant to a formal process. [516] Requiring workforce members to affirmatively acknowledge that a violation of the organization's HIPAA policies or procedures may result in sanctions. [517] Documenting the sanction process, including the personnel involved, the procedural steps, the time-period, the reason for the sanction(s), and the final outcome of an investigation. [518] Creating sanctions that are appropriate to the nature of the violation. [519] Creating sanctions that vary depending on factors such as the severity of the violation, whether the violation was intentional or unintentional, and whether the violation indicated a pattern or practice of improper use or disclosure of [PHI]. [520] Creating sanctions that range from a warning to termination. [521] Providing examples of potential violations of policy and procedures. [522] Generally, it is important for a regulated entity to consider whether its sanction policies align with its general disciplinary policies, and how the individuals or departments involved in the sanction processes can work in concert, when appropriate. Regulated entities may also want to consider how sanction policies can be fairly and consistently applied throughout the organization, to all workforce members, including management. [523] The deterrent effect of penalizing noncompliance and misconduct paired with clear communications about the consequences of noncompliance can promote greater compliance with the HIPAA Rules through accountability, understanding, and transparency. (printed page 946) i. Section 164.308(a)(7)(i)-Standard: Information System Activity Review As described in previously issued HHS guidance, review of activity in its relevant electronic information systems and their components, including workstations, [524]

ing their own suppliers and serving as the principal manager for those relationships. Most companies reported using a standardized framework to manage cyber supply chain risks across the organization. These frameworks are either based on standards and best practices (e.g., NIST Cybersecurity Framework (CSF), driven by regulations (e.g., North American Electric Reliability Corporation critical infrastructure protection (NERC CIP), Health Insurance Portability and Accountability Act (HIPAA)) or developed internally (e.g., through internal ERM framework). Having a standardized approach helps multiple teams across the organization to cohesively handle cyber supply chain risks. The following are some of the benefits of adopting standardized frameworks:

Control AM-1: concept of least functionality) is created and maintained. | understood and can be maintained. Install and configure PNT devices and components per manufacturer instructions using established safety and best practices guidelines. Understand the limitations of the original equipment manufacturer (OEM) equipment being fielded and consider the ability of the PNT devices and components to be suitable for the site's environment and adaptable to new features and protection mechanisms for PNT data. Periodically review and simplify PNT systems to reduce unknown interactions and effects. Configuring the PNT devices and components in a manner such that only essential capabilities are provided can reduce complexity and may reduce the attack surface. Network configuration and deployment can impact recovery time in the event of a path or node failure. Verify that the baseline configuration results in a system that meets the baseline PNT performance requirements, such as uncertainty, wander, and jitter tolerances. | GPS-SPS 2.4 ICAO 9849 6.4, Appendix F 5.2, 5.3 IEEE 1588 Annex P IEEE 2030.101 4.6-4.13, 4.15 IETF 5906 5 IETF 8633 2-9 IMO 1575 C.1, E ITU G. 8272 I.1 ITU-T G.8275 7, 8 ITU-T GNSS 2, 4, 5, Appendix V, VII NIST SP 800-53 Rev.

Several commenters expressed concern with the 180-day timeline to close out POA&Ms or limits on which practices can be placed on them. Recommendations for changing the POA&M timeline ranged from completely deleting the time limit to extending it by 1 to 3 years. One variation was to permit more than 180 days for closeout only during an initial one-year 'ramp-up' period. One commenter encouraged DoD to reduce POA&M restrictions to facilitate contractors' genuine attempts to meet requirements and mitigate information security risks. Three commenters also thought the rule should allow contractors to request approval to delay POA&M close-out when meeting the original timeline is impracticable, while another commenter suggested defining the close-out timeline in the contract, allowing negotiation of extension or renewal of POA&Ms through the contracting officer. Two commenters asked when the 180-day timeline begins and one asked what actions occur if the POA&M is not closed out within that period. Four commenters noted that the number of security requirements explicitly precluded from POA&Ms makes CMMC challenging and requested greater flexibility in how many, and which practices may be included. Three commenters recommended that companies be allowed to have any number of failed practices reassessed for up to six-months after an assessment without having to complete and pay for a new full assessment. Three other commenters recommended that the DoD allow for risk informed POA&Ms, while one stated that the rule should not specify which requirements must be met. One commenter requested clarification on how many items of each point value may be included on a POA&M for CMMC Level 2 conditional certification. One commenter also asked DoD to consider abandoning controls with high failure rates, lowering score requirements based on evidence of sufficient mitigation. Several comments expressed concern that CMMC conditional certification does not allow higher weighted practices on a POA&M and recommended the rule reduce those restrictions to allow more security practices. One commenter also recommended eliminating weighting altogether, permitting any requirement to be part of the POA&M. As rationale, one commenter referenced DFARS clause 252.204-7012 verbiage that permits contractors to request DoD CIO approval to vary from NIST SP 800-171 requirements, saying that since all approved variances are considered as 'Not Applicable', all requirements should be POA&M eligible. Two commenters asked where POA&Ms are maintained, who is responsible for validating close-out, and whether affirmation is required after each assessment (including POA&M close-out). One commenter asked about applicability of the 180-day POA&M close-out requirement to Critical, High, Medium, or Low findings against Service Level Agreements. One commenter recommended that a description of appropriate POA&M entries to be added to the rule and (printed page 83133)

, a major rule is a rule that the Administrator of the Office of Information and Regulatory Affairs of the Office of Management and Budget finds has resulted in or is likely to result in (a) an annual effect on the economy of \$100,000,000 or more; (b) a major increase in costs or prices for

consumers, individual industries, Federal, State, or local government agencies, or geographic regions; or (c) significant adverse effects on competition, employment, investment, productivity, innovation, or on the ability of United States-based enterprises to compete with foreign-based enterprises in domestic and export markets. This rule has been designated a major rule as it is expected to have annual effect on the economy of \$100M dollars or more. C. Public Law 96-354, ·Regulatory Flexibility Act· (5 U.S.C. 601) The Department of Defense Chief Information Officer certified that this rule is subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would, if promulgated, have a significant economic impact on a substantial number of small entities. DoD has considered previous comments from Small Business Administration (SBA) regarding the impact and cost to small businesses to implement CMMC. In July 2022, the CMMC PMO met with the Office of Advocacy for the U.S. SBA to address the revisions planned in CMMC that are responsive to prior SBA concerns, with which the SBA was satisfied. An Initial Regulatory Flexibility Analysis that includes a detailed discussion and explanation about the assumptions and methodology used to estimate the cost of this regulatory action on small entities follows and is available at <https://www.regulations.gov> (search for ·DoD-2023-OS-0063· click ·Open Docket· and view ·Supporting Documents·). This initial regulatory flexibility analysis has been prepared consistent with 5 U.S.C. 603 . (1) Reasons for the Action This proposed rule is necessary to create a secure and resilient supply chain, by addressing threats to the U.S. economy and national security from ongoing malicious cyber activities and preventing theft of hundreds of billions of dollars of U.S. intellectual property. The President's Executive Order (E.O.) 14028, ·Improving the Nation's Cybersecurity·, [52] emphasized that industrial security needs strengthening to ensure investments are not lost through intellectual property theft, among other supply chain risks. Currently, the FAR and DFARS prescribe contract clauses intended to protect FCI and CUI within the DoD supply chain. Specifically, the clause at FAR 52.204-21, Basic Safeguarding of Covered Contractor Information Systems, is prescribed at FAR 4.1903 for use in Government solicitations and contracts when the contractor or a subcontractor at any tier may have FCI residing in or transiting through its information system. The FAR clause focuses on ensuring a basic level of cybersecurity hygiene and is reflective of actions that a prudent businessperson would employ. In addition, DFARS clause 252.204-7012,

(2) Specific individuals or institutions need not be identified by name, particularly if these sources have been granted confidentiality. (see §310.29(b)). (p) Exemptions claimed for the System. (1) If no exemption has been claimed for the system, indicate ·None·. (2) If an exemption is claimed, cite the exemption as well as identifying the CFR section containing the exemption rule for the system. (q) Maintaining the Master DoD System Notice Registry. (1) The DPO maintains a master registry of all DoD record systems notices. (2) The DPO also posts all DoD system notices to a public Web site (see <http://www.defenselink.mil/privacy/notice/>). §310.33 New and altered record systems. (a) Criteria for a new record system. (1) If a Component is maintaining a system of records as contemplated by §310.10(a), and a system notice has not been published for it in the Federal Register , the Component shall establish a system notice consistent with the requirements of this subpart. (2) If a notice for a system of records has been canceled or deleted but a determination is subsequently made that the system will be reinstated or reused, the system may not be operated (i.e., information collected or used) until a new notice is published in the Federal Register . (b) Criteria for an altered record system. A system is considered altered whenever one of the following actions occurs or is proposed: (1) A significant increase or change in the number or type of individuals about whom records are maintained. (i) Only changes that alter significantly the character and purpose of the record system are considered alterations. (ii) Increases in numbers of individuals due to normal growth are not considered alterations unless they truly alter the character and purpose of the system. (iii) Increases that change significantly the scope of population covered (for example, expansion of a system of records covering a single command's enlisted personnel to include all of the Component's enlisted personnel would be considered an alteration). (iv) A reduction in the number of individuals covered is not an alteration, but only an amendment. (see §310.34(a).) (v) All changes that add new categories of individuals to system coverage require a change to the ·Categories of individuals covered by the system· caption of the notice (see §310.32(e)) and may require changes to the ·Purpose(s)· caption (see §310.32(h)). (2) An expansion in the types or categories of information maintained. (i) The addition of any new category of records not described under the (printed page 18779) ·Categories of Records in the System· caption is considered an alteration. (ii) Adding a new data element that is clearly within the scope of the categories of records described in the existing notice is an amendment. (see §310.34(a)). An amended notice may not be required if the data element is clearly

covered by the record category identified in the existing system notice.

for better deploying the technology? Often we are not seeing that information.' The introduction of IoT devices creates significant challenges for security assessment of federal information systems. Cybersecurity must be assessed both at the component level (i.e., individual IoT devices) and the system level (i.e., the integration of a set of IoT devices with traditional IT in a specific operating environment). An additional challenge is security testing of systems with IoT devices, especially when evaluating the impacts of updates to those devices. For example, if automatic security updates of IoT devices are enabled, when and by whom are tests of those updates to be performed?

CIS Safeguard 9.2 · Use DNS Filtering Services Use DNS filtering services on all enterprise assets to block access to known malicious domains. Implementation Groups: 1,2,3 Asset Type: network Security Function: protect Parent Control: Email and Web Browser Protections

- · Cybersecurity risks to DDM are very real; - · Cybersecurity threats have the potential to disrupt the manufacturing revolution; - · There is real opportunity to improve the security of the manufacturing supply chain, and - · The time to build cybersecurity in to the DDM process is now. The agenda contained an invited talk, four presentations, and a panel discussion that exemplified diverse perspectives. A concluding working session captured the viewpoints of the attendees in several key areas. In addition, attendees provided inputs on the risks, challenges, existing solutions, and potential/theoretical solutions for cybersecurity in DDM. Responses focused around culture / humans, threats to the integrity of design, technological capabilities - especially around quality control and event detection, and guidance specific to cybersecurity in DDM. In this work, the authors scope their research solely on Additive Manufacturing (AM; also referred to as '3D Printing') technologies. The AM process chain has unique vulnerabilities that warrant a detailed investigation due to their ability to fabricate parts in a layer-wise fashion. Because of the potential damage from a cyber-physical attack, there is a need to look at AM systems to determine what vulnerabilities exist and how to prevent and mitigate the threat of cyber-attacks.

necessary information system updates, patches, or (printed page 83219) reconfiguration as threats evolve) in implementation of requirements and documents how they will be mitigated, corrected, or eliminated. The OSA defines the format (e.g., document, spreadsheet, database) and specific content of its operational plan of action. An operational plan of action does not identify a timeline for remediation and is not the same as a POA&M, which is associated with an assessment for remediation of deficiencies that must be completed within 180 days. (CMMC-custom term) Operational Technology (OT) means programmable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment). These systems or devices detect or cause a direct change through the monitoring or control of devices, processes, and events. Examples include industrial control systems, building management systems, fire control systems, and physical access control mechanisms, as defined in NIST SP 800-160 V2R1 (incorporated by reference, see §-170.2). Organization-defined means as determined by the OSA except as defined in the case of Organization-Defined Parameter (ODP). (CMMC-custom term) Organization-Defined Parameters (ODPs) means selected enhanced security requirements contain selection and assignment operations to give organizations flexibility in defining variable parts of those requirements, as defined in NIST SP 800-172A Mar2022 (incorporated by reference, see §-170.2). Note 1 to ODPs: The organization defining the parameters is the DoD. Organization Seeking Assessment (OSA) means the entity seeking to undergo a self-assessment or certification assessment for a given information system for the purposes of achieving and maintaining any CMMC Status. The term OSA includes all Organizations Seeking Certification (OSCs). (CMMC-custom term) Organization Seeking Certification (OSC) means the entity seeking to undergo a certification assessment for a given information system for the purposes of achieving and maintaining the CMMC Status of Level 2 (C3PAO) or Level 3 (DIBCAC). An OSC is also an OSA. (CMMC-custom term) Out-of-Scope Assets means assets that cannot process, store, or transmit CUI because they are physically or logically separated from information systems that do process, store, or transmit CUI, or are inherently unable to do so; except for assets that provide security protection for a CUI asset (see the definition for Security Protection Assets). (CMMC-custom term) Periodically means occurring at a regular interval as determined by the OSA that may not exceed one year. (CMMC-custom term) Personally Identifiable Information means information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual, as defined in

) The sale or disposal of the entity's assets or a substantial part thereof. (2) Pledges, mortgages, or other encumbrances on the entity's assets, capital stock, or ownership interests. (3) Mergers, consolidations, or reorganizations. (4) Dissolution. (5) Filing of a bankruptcy petition. (B) The trustees or proxy holders may consult with the foreign owner, or vice versa, where otherwise consistent with U.S. laws, regulations, and the terms of the VT or PA. (C) The trustees or proxy holders assume full responsibility for the foreign owner's voting interests and for exercising all governance and management prerogatives relating thereto to ensure the foreign owner will be insulated from the entity, thereby solely retaining the status of a beneficiary. The entity must be organized, structured, and financed to be capable of operating as a viable business entity and independent from the foreign owners' interests that required FOCI mitigation or negation. (v) Combination measures. The CSA may apply combinations of the measures in paragraphs (d)(2)(i) through (d)(2)(iv) in this section or other similar measures that effectively mitigate or negate the risks involved with foreign ownership. (e) Limited entity eligibility determination due to FOCI. In accordance with the provisions of this section and CSA-provided guidance, a limited entity eligibility determination may be an option for a single, narrowly defined contract, agreement, or circumstance for entities under FOCI without mitigation or negation. Limitations on access to classified information are inherent with the granting of limited entity eligibility determinations and are imposed upon all of the entity's employees regardless of citizenship. (1) In exceptional circumstances, when an entity is under FOCI, the CSA may decide that a limited entity eligibility determination is appropriate when the entity is unable or unwilling to implement FOCI mitigation or negation measures, and the conditions in paragraphs (e)(1)(i) through (iii) of this section are met. This is not the same as a limited entity eligibility determination for purposes not related to FOCI. Information on limited entity eligibility determinations for purposes other than FOCI can be found in § 117.9(m). A CSA may decide that a limited entity eligibility is appropriate for an entity under FOCI if: (i) The limited entity eligibility determination is in accordance with national security interests and a GCA has informed the CSA that access to classified information by the contractor is essential to contract or agreement performance. (ii) There is an industrial security agreement with the foreign government of the country from which the FOCI is derived. (iii) The contractor meets all other entity eligibility requirements outlined in § 117.9(c) except that KMP, other than the FSO, may be citizens of the country from which the FOCI derives and the United States has obtained security assurances at the appropriate level from that country.

CIS Safeguard 11.5 · Test Data Recovery Test backup recovery quarterly, or more frequently, for a sampling of in-scope enterprise assets. Implementation Groups: 2,3 Asset Type: data Security Function: recover Parent Control: Data Recovery

Some public comments received reflect a misinterpretation of the cost estimates that accompany this rule, which are representative of average assessment efforts, and do not include actual prices of C3PAO services available in the marketplace. Market forces of supply and demand will determine C3PAO pricing for CMMC Level 2 certification assessments. Costs associated with meeting the requirements of existing DFARS clause 252.204-7012 are not captured in the CMMC rule documentation. Please refer to 81 FR 72990 , October 21, 2016, for DoD's final rule implementing the DoD's requirement that contractors shall implement NIST SP 800-171 as soon as practical, but not later than December 31, 2017. Public comments related to implementation costs were published with that final rule, along with DoD's responses. Within the limitations of section § 170.21 Plan of Action and Milestones Requirements, offerors may bid on contract opportunities while continuing to work towards full compliance. Verifying compliance with applicable security requirements may increase costs and is necessary for the adequate protection of DoD FCI and CUI. The cost of lost technological advantage over potential adversaries is far greater than the costs of such enforcement. The value of information and impact of its loss does not diminish when the information is shared with contractors. At the time of contract award, the DoD may not have visibility into whether the prime contractor's decision to further disseminate DoD FCI and CUI. However, FAR clause 52-204-21, DFARS clause 252.204-7012, and DFARS clause 252.204-7021 require the prime contractor to flow down these clauses and the included information security requirement to any subcontractor that will process, store, or transmit FCI or CUI, as applicable. Decisions regarding DoD's information that must be shared to support completion of the contract tasks, including those performed by subcontractors, takes place between the prime contractor and their subcontractors. The DoD cannot dictate business practices between prime contractors and their subcontractors, who should work together to determine

the necessary flow down of FCI and CUI, only as needed in performance of the contract, and ensuring compliance with the CMMC security requirements and in consideration of minimizing the burden. While DoD understands the burden on small business, it must enforce CMMC requirements uniformly across the Defense Industrial Base for all contractors who process, store, or transmit FCI and CUI. The requirements necessary to protect a single document are the same as to protect many documents.

(vi) Requestors affiliated with the DoD may not use official government supplies or equipment to include mailing addresses, work phones/faxes, or DoD-issued email accounts to make requests. If requests are received using DoD equipment, the requestor will be advised to make a new request, using non-DoD equipment, and processing of their request will begin only after such new request is received. (3) The System Manager shall mail a written acknowledgement of the request for access to the individual within 10 working days of receipt. The acknowledgement shall identify the request and may, if necessary, request any additional information needed to access the record, advising the requestor that they have 20 calendar days to reply. No acknowledgement is necessary if the request can be reviewed and processed, to include notification to the individual of a grant or denial of access, within the 10 working day period. Whenever practical, the decision to grant or deny access shall be made within 30 working days. For requests presented in person, written acknowledgement may be provided at the time the request is presented. (4) When a request for access is received, System Managers shall promptly take one of three actions on requests to access records: (i) If no portions of the record are exempt, pursuant to the published SORN, 32 CFR part 310, subpart F, and section 7 of 32 CFR part 329, the request for access shall be granted and the individual will be provided access to all records about him or her. If there is information within the record not about the record subject (e.g. third party information) that information will be removed and referred to the Chief of the OIP for processing under 5 U.S.C. 552, pursuant to 32 CFR part 286. (ii) If the System Manager finds that the record, or portions of the record, is exempt from access pursuant to the published SORN, 32 U.S.C. part 310, subpart F, and section 7 of 32 U.S.C. part 329, they will refer the recommended denial to the Chief of the OIP, through their Director, within 10 working days of receipt. The referral will include the following: (A) Written recommendation for denial explaining which portion(s) of the record should be exempt from access and a discussion for why the record, or portions of the record, should be denied. (B) The record, or portions of the record, being recommended for denial. If only portions of records are recommended for denial they must be clearly marked or highlighted. (C) The original request and any correspondence with the requestor. (D) A clean copy of the record.

a. The clause at DFARS 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, covers cyber incident reporting requirements for incidents that affect a covered contractor information system or the covered defense information residing therein, or that affects the contractor's ability to perform the requirements of the contract that are designated as operationally critical support and identified in the contract. b. The provision at DFARS 252.204-7008, Compliance with Safeguarding Covered Defense Information Controls, requires an offeror that proposes to vary from any of the security controls of National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 in effect at the time the solicitation is issued to submit to the contracting officer a written explanation of how the specified security control is not applicable or an alternative control or protective measure is used to achieve equivalent protection. c. The provision at DFARS 252.239-7009, Representation of Use of Cloud Computing, requires offerors to report that they anticipate or do not anticipate utilizing cloud computing service in performance of a contract resulting from a solicitation containing the provision. The representation will notify contracting officers of the applicability of the cloud computing requirements of the DFARS 252.239-7010 clause of the contract. d. The clause at DFARS 252.239-7010, Cloud Computing Services, requires reporting of cyber incidents that occur when DoD is purchasing cloud computing services. These DFARS provisions and clauses facilitate mandatory cyber incident reporting requirements in accordance with statutory regulations. When reports are submitted, DoD will analyze the reported information for cyber threats and vulnerabilities in order to develop response measures as well as improve U.S. Government understanding of advanced cyber threat activity. In addition, the security requirements in NIST SP 800-171 are specifically tailored for use in protecting sensitive information residing in contractor information systems and generally reduce the burden placed on contractors by eliminating Federal-centric processes and requirements. The information provided will inform DoD in assessing the overall risk to DoD covered defense information on unclassified contractor systems and networks. DoD Clearance Officer: Mr. Reginald T. Lucas. Requests for copies of the information collection proposal should be sent to Mr. Lucas at

. (1) No fees may be charged by any DoD Component if the total assessable fees are less than or equal \$25.00. For requesters in the educational institution, noncommercial scientific institution, or news media categories, the Components shall provide all search time and the first 100 pages of duplication without charge. For requesters in the all other category, the Components shall provide the first 2 hours of search time, and the first 100 pages of duplication without charge. The Components shall provide all review time without charge except for requesters in the commercial category. Time expended shall be computed to the nearest 15 minutes. (2) Requesters receiving the first 2 hours of search and the first 100 pages of duplication without charge are entitled to such only once per request. Therefore, if the Component, after completing its portion of a request, finds it necessary to refer the request to a subordinate office, another DoD Component, or another Federal agency for action on their portion of the request, the referring Component shall inform the recipient of the referral of the expended amount of search time and duplication cost to date. (3) For the purposes of these restrictions, the word pages refers to paper copies of a standard size, which will normally be 8 1/2 x 11 or 11 x 14. Thus, requesters would not be entitled to 100 microfiche or 100 computer disks, for example. (4) In the case of computer searches, the first 2 free hours will be determined against the salary scale of the individual operating the computer for the purposes of the search. As an example, when the direct costs of the computer central processing unit, input-output devices, and memory capacity equal \$40.00 (2 hours of equivalent search at the clerical level), amounts of computer costs in excess of that amount are chargeable as computer search time. In the event the direct operating cost of the hardware configuration cannot be determined, computer search shall be based on the salary scale of the operator executing the computer search. See § 286.25(b)(1) for further details regarding fees for computer searches. (c) Fee waivers . (1) When assessable costs for a FOIA request total \$25.00 or less, fees shall be waived automatically for all requesters, regardless of category. (2) Documents shall be furnished without charge, or at a reduced charge, when the Component determines that waiver or reduction of the fees is in the public interest because furnishing the information is likely to contribute significantly to public understanding of the operations or activities of the Department of Defense and is not primarily in the commercial interest of the requester. Decisions to waive or reduce fees that exceed the automatic waiver threshold shall be made on a case-by-case basis and after a search for responsive records is completed, consistent with the following factors:

(i) Exemption. Any portion of this record system which falls within the provisions of 5 U.S.C. 552a(k)(2) , (k)(5) and (k)(6) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), and (e)(4)(I). (ii) Authority. 5 U.S.C. 552a(k)(2) , (k)(5) and (k)(6). (iii) Reasons. The reasons for asserting these exemptions are to ensure the integrity of the adjudication process used by the Agency to determine the suitability, eligibility or qualification for Federal service with the Agency and to make determinations concerning the questions of access to classified materials and activities. The proper execution of this function requires that the Agency have the ability to obtain candid and necessary information in order to fully develop or resolve pertinent information developed in the process. Potential sources, out of fear or retaliation, exposure or other action, may be unwilling to provide needed information or may not be sufficiently frank to be a value in personnel screening, thereby seriously interfering with the proper conduct and adjudication of such matters; and protects information used for medical, psychological evaluations, security questionnaires and polygraph testing. (4) [Reserved] (5) System identifier and name. LDIA 10-0001, Equal Opportunity, Diversity and Alternate Dispute Resolution Records. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (b)(5)(i). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. The specific sections of 5 U.S.C. 552 a from which the system is to be exempted are 5 U.S.C. 552a (c)(3) and (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (H), and (I), (e)(5), (f), and (g). (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. (A) From subsection (c)(3) because to grant

access to an accounting of disclosures as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation or prospective interest by DIA or other agencies. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence.

[s://doi.org/10.6028/NIST.SP.800-160v1r1](https://doi.org/10.6028/NIST.SP.800-160v1r1) - [17] Boyens JM, Smith AM, Bartol N, Winkler K, Holbrook A, Fallon M (2022) Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-161r1-upd1, Includes updates as of November 1, 2024.
<https://doi.org/10.6028/NIST.SP.800-161r1-upd1> - [18] Heckert N, Filliben J, Croarkin C, Hembree B, Guthrie W, Tobias P, Prinz J (2012) NIST/SEMATECH e-Handbook of Statistical Methods. (National Institute of Standards and Technology, Gaithersburg, MD). <https://doi.org/10.18434/M32189> - [19] Stevens SS (1946) On the Scales of Measurement. Science 103(2684):677-680.
<http://www.jstor.org/stable/1671815> - [20] Turan MS, Barker E, Kelsey J, McKay KA, Baish ML, Boyle M (2018) Recommendation for the Entropy Sources Used for Random Bit Generation. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-90B. <https://doi.org/10.6028/NIST.SP.800-90B> - [21] Stolfo S, Bellovin S, Evans D (2011) Measuring Security. IEEE Security & Privacy 9(3):6065. <https://doi.org/10.1109/MSP.2011.56> - [22] Ross R, Pillitteri V, Graubart R, Bodeau D, McQuaid R (2021) Developing Cyber-Resilient Systems: A Systems Security Engineering Approach. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-160v2r1. <https://doi.org/10.6028/NIST.SP.800-160v2r1> - [23] Schroeder K, Trinh H, Pillitteri VY (2024) Measurement Guide for Information Security: Volume 2 - Developing an Information Security Measurement Program. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) NIST SP 800-55v2. <https://doi.org/10.6028/NIST.SP.800-55v2>

) Request the contractor to provide information on all impacted contracts, both prime and subcontracts, unless the contractor is prohibited by contract from revealing their existence to DSS. In such instances, DSS will request that the contractor notify the government contracting officer and Program Security Officer of the need for a NID. (2) Provide written notification to the individual designated by the Component, in accordance with paragraph (f) of § 117.55 within 30 calendar days of identifying the requirement for a NID. (3) Provide to appropriate GCAs the contractor's proposed FOCI action plan, any associated risk assessments, and DSS' recommendation for FOCI mitigation. (4) Ask the GCA to identify all of the GCA's contracts affected by the proposed SSA that require a NID decision, unless the activity is unacknowledged. The cognizant SAPCO will inform the DoD SAPCO of any unacknowledged SAPs affected by the proposed SSA and consequently the NID requirement. (5) Provide OUSD(I) Security Directorate and the OUSD(AT&L), Deputy Assistant Secretary of Defense for Manufacturing and Industrial Base Policy, a monthly report of pending NID decisions that: (i) Exceed 30 calendar days from the date of the DSS written notice to the applicable GCA. (ii) Have been pending for NSA, ODNI, or DOE concurrence for more than 30 calendar days. (B) OUSD(I) will intervene, as warranted, with GCAs regarding NID decisions pending beyond 30 calendar days from the date of the DSS written notice, as well as with NSA, ODNI, and DOE regarding concurrence decisions that remain pending beyond 30 days from the date of the GCA request. (C) OUSD(AT&L) will confer, as warranted, with the applicable DoD Service Acquisition Executive or component equivalent about unresolved NID decisions. (D) The GCA will, upon written notification by DSS of the need for a NID: (1) Review the FOCI action plan proposed by the uncleared company, in addition to any associated risk assessments and the DSS analysis of the appropriate FOCI mitigation based on the existing FOCI factors. (2) Consider the FOCI factors noted in paragraph (b)(3) of this section in the aggregate with any associated risk assessments and DSS' analysis to determine whether to issue a NID. (3) Provide DSS, as appropriate, one of the following within 30 calendar days of the DSS written notification that a NID is required: (i) A final, documented NID with a copy provided to the contractor. If the NID is not specific to a single program, project, or contract (e.g., a blanket NID), the GCA will also forward a copy of the NID to the OUSD(I) Security Directorate. (ii) A copy of the GCA's request for NID concurrence sent to NSA, ODNI, or DOE, when access to COMSEC, SCI, or RD is involved. The GCA will request that NSA, ODNI, or DOE respond within 30 calendar days of the date of the GCA's written request directly to DSS with a copy to the GCA. (iii) A GCA decision that it will not issue a NID. (4

Based on its own investigations and compliance reviews, news reports, and published studies, the Department is aware that many regulated entities have failed to implement adequate technical controls, or, in some cases, any technical controls. For example: A large health system that operates in multiple States experienced a massive data breach resulting from a hacking incident. OCR's investigation found indications of potential failures to sufficiently monitor its activity in its information systems that was insufficient to protect against a cyberattack, implement an authentication process to safeguard its ePHI, and have security measures in place to protect ePHI from unauthorized access when it was being transmitted electronically. [687] A Rhode Island nonprofit health system experienced a data breach resulting from the theft of a laptop. OCR's investigation found indications of potential failures to encrypt ePHI, despite the entity's determination to implement encryption, and a lack of device and media controls. [688] At a large covered entity, workforce members used their log-in credentials to access medical records maintained in the entity's EHR without a job-related purpose. [689] OCR's investigation found evidence of potential violations of the requirement to implement reasonable and appropriate policies and procedures to comply with the standards, implementation specifications, or other requirements of the Security Rule. [690] At another covered entity, the potential failure to implement hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use ePHI, among other things, enabled a workforce member to sell the ePHI of more than 12,000 individuals. [691] Some investigations have found indications that regulated entities may implement technical controls that address some, but not all, users of and technology assets in a relevant electronic information system, such as software, hardware, and persons involved in the development, configuration, and implementation of technical controls. [692] And other investigations have suggested that the potential failure of a regulated entity to have security measures in place to protect ePHI from unauthorized access when it is transmitted electronically has resulted in increased risk and breaches of ePHI. [693] Common network segmentation practices would have substantially reduced the risk to the security ePHI and could have prevented such breaches. Beyond the health care sector, threat actors have been able to gain access to networks by compromising user accounts and taking advantage of insufficient network segregation. For example, the 2014 Home Depot breach involved the compromise of a third-party vendor's username and password to enter Home Depot's network, which allowed hackers to obtain elevated rights to navigate to self-checkout point-of-sale system. [694]

Section 170.15 addresses how an OSA will achieve and maintain compliance with the CMMC Status of Level 1 (Self). The OSA must successfully implement the security requirements listed in § 170.14(c)(2) within their Level 1 CMMC Assessment Scope as described in § 170.19(b). Successful implementation requires meeting all objectives defined in NIST SP 800-171A Jun2018 for the corresponding CMMC Level 1 security requirements as outlined in the mapping table 1 to § 170.15(c)(1)(i). After implementation, the OSA must perform a Level 1 self-assessment to verify the implementation and score themselves using the scoring methodology provided in § 170.24. All objectives must be met in order for a security requirement to be considered fully implemented; no security requirements may be placed on a POA&M for Level 1. The OSA must then input their results into SPRS as described in § 170.15(a)(1)(i) and submit an affirmation as described in § 170.22. In order to be eligible for a contract with a requirement for the CMMC Status of Level 1 (Self), the OSA must have achieved a CMMC Status of Final Level 1 (Self) and have submitted an affirmation. These activities must be completed annually.

Section 170.16-CMMC Level 2 Self-Assessment and Affirmation Requirements Section 170.16 addresses how an OSA will achieve and maintain compliance with the CMMC Status of Level 2 (Self). The OSA must successfully implement the security requirements listed in § 170.14(c)(3) within its Level 2 CMMC Assessment Scope as described in § 170.19(c). Successful implementation requires meeting all objectives defined in NIST SP 800-171A Jun2018 for the corresponding CMMC Level 2 security requirements. Requirements for ESPs and CSPs that process, store, transmit CUI are provided in § 170.16(c)(2) and (3). After implementation, the OSA must perform a Level 2 self-assessment to verify the implementation and score themselves using the scoring methodology provided in § 170.24. All objectives must be met in order for a security requirement to be considered fully implemented; in some cases, if not all objectives are met, some security requirements may be placed on a POA&M as provided for in § 170.21. If the minimum score has been achieved and some security requirements are in a POA&M, the OSA has achieved the CMMC Status of Conditional Level 2 (Self); if all requirements are MET as defined in § 170.24(b), the OSA has achieved a CMMC Status of Final Level 2 (Self). For Conditional Level 2 (Self), a POA&M closeout must be conducted within 180 days as described in § 170.21(b) or the Conditional Level 2 (Self) CMMC Status will expire. After a Level 2 self-assessment, as well as after a POA&M closeout, the OSA

must input their results into SPRS as described in § 170.16(a)(1)(i) and submit an affirmation as described in § 170.22.

3.3.4 Security Tag Type 3 | 4. 3.3.4 Security Tag Type 3 | 4. 3.3.4 Security Tag Type 3 | 4.

Purpose and Audience This guide is intended for Organizations Seeking Certification (OSCs) that will be obtaining a Level 3 certification assessment and the professionals or companies that will support them in those efforts. **Identifying the CMMC Assessment Scope** CMMC Assessment Scope - Level 3 - Version 2.13 2 Identifying the CMMC Assessment Scope An assessment, as defined in 32 CFR § 170.4 , means the testing or evaluation of security controls to determine the extent to which the controls are implemented correctly, operating as intended, and producing the desired outcome with respect to meeting the security requirements for an information system or organization. This document should help the reader understand the categorization of assets that, in turn, inform the specification of the boundary for a CMMC assessment. The scope of the CMMC Program does not include classified assets, even if they contain applicable Controlled Unclassified Information (CUI). Prior to conducting a Level 3 certification assessment, the CMMC Assessment Scope must be defined as addressed in 32 CFR § 170.19(d). The CMMC Assessment Scope informs which assets within the OSC's environment will be assessed and the details of the assessment. When seeking a Level 3 certification assessment, the OSC must have a Final Level 2 (C3PAO) CMMC Status for the same CMMC Assessment Scope as the Level 3 assessment. Any Level 2 Plan of Action and Milestones (POA&M) items, as defined in 32 CFR §170.4 , must be closed prior to the initiation of the Level 3 assessment. The Level 3 CMMC Assessment Scope may be a subset of the Level 2 CMMC Assessment Scope (e.g., a Level 3 data enclave with greater restrictions and protections within the Level 2 data enclave). Assets designated as Contractor Risk Managed Assets (CRMAs) in the Level 2 CMMC Assessment Scope are treated as CUI assets if they fall within the Level 3 CMMC Assessment Scope. OSCs may choose to designate them as CUI assets for the Level 2 certification assessment and have them assessed by a C3PAO. Since the assessment requirements for Specialized Assets differ between Level 2 and Level 3, the OSC may choose to have them assessed by a C3PAO during the Level 2 certification assessment. During a Level 3 certification assessment, DCMA DIBCAC may check any Level 2 security requirement of any in-scope asset. CRMAs and Specialized Assets not assessed to the Level 3 scoping requirements by a C3PAO during the Level 2 certification assessment, will undergo limited checks for compliance with Level 2 security requirements during the DCMA DIBCAC Level 3 certification assessment and will be assessed against all CMMC Level 3 security requirements. **CMMC Asset Categories** For a Level 3 assessment, assets are mapped into one of four categories defined in 32 CFR § 170.19(d)(1) Table 4 . This table describes each asset category and its corresponding OSC requirements and CMMC assessment requirements. Additional information about each asset category is provided in the ensuing sections.

3.2.2 | Logging Capabilities ... 3.2.2 Logging Capabilities IDPSs typically perform extensive logging of data related to detected events. 3.2.2 provides more information on ongoing maintenance of the technologies, with Section 3.

32 CFR part 2002 and the completion of the SF XXX during acquisition planning. (6) FAR 7.105, Contents of written acquisition plans. CUI is added to the security considerations to be addressed during acquisition planning. (7) At FAR 7.503, Policy, language has been revised to clarify that the list of examples of functions generally not considered to be inherently governmental functions, includes contractors working in any situation that permits or might permit them to gain access to CUI. (8) FAR subpart 9.5, Organizational and Consultant Conflicts of Interest, includes updates to FAR 9.505, 9.505-4, and 9.508 to make clear proprietary information is contractor proprietary business information. (9) FAR 11.002, Policy. New language is added to incorporate the requirements for CUI and use of the SF XXX when describing agency needs. (10) FAR 12.202, Market research and description of agency need. New language is added to incorporate the requirements for CUI and the SF XXX in requirements documents for the acquisition of commercial products and commercial services. (11) At FAR 15.407-1, a reference to CUI and classified information is added to clarify the type of information that should be protected from improper disclosure. (12) At FAR subpart 15.6, conforming changes are made to change ·proprietary information· and ·restrictive legend· or ·legend· to ·contractor proprietary business information· and ·administrative marking·, respectively. (13) FAR 27.203, Security requirements for patent applications and other patent information. A new section is added to inform contracting officers that CUI safeguarding requirements apply to patent application and other patent information. (14) FAR part 52. A new provision FAR 52.204-WW, Notice of Controlled

Unclassified Information Requirements, is added to inform offerors of requirements on restricted use of Government-provided information, on appropriately identifying sensitive offeror-provided information, and on notifying the Government regarding unmarked or mismarked CUI. A new FAR clause 52.204-XX, Controlled Unclassified Information, is added to require contractors to comply with applicable CUI requirements, if the SF XXX indicates that the contractor is expected to collect, develop, receive, transmit, use, handle, or store CUI under the contract. A new FAR clause 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information, is added to apply to contracts in which the requiring activity indicates on the SF XXX that no CUI is involved in the performance of the contract. CUI requirements include: Requirements for how the contractor must mark CUI submitted to the Government and notify the Government of any mismarked or unmarked CUI discovered; Restrictions on the contractor's use of Government-provided information apply whether or not the information is marked as CUI;

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 iii Note to Reviewers 45 The following provides a summary of the significant changes that have been made to SP 800- 172 in transitioning to Revision 3: · Streamlined introductory information in Sec. 1 and Sec. 2 to improve clarity and understanding · Increased specificity of the enhanced security requirements to remove ambiguity, improve the effectiveness of implementation, and clarify the scope of assessments · Grouped enhanced security requirements, where possible, to improve understanding and the efficiency of implementations and assessments · Removed outdated and redundant enhanced security requirements · Added new enhanced security requirements based on (1) the la

3.2.11 | Lack of Concern | 19 | | 3. 3.2.11 Lack of Concern Wealso found examples of various levels of lack of concern, with seven participants having neither privacy nor security concerns.

ing and risk management activities. It must incorporate an application system perspective, and give more detailed consideration to confidentiality, integrity, and availability protection requirements.

|| | PAGE | |----|-----
|-----

---|| IV. | OBSERVATIONS, COMMENTS, AND LESSONS LEARNED - CIVILIAN AGENCY PLANS | OBSERVATIONS, COMMENTS, AND LESSONS LEARNED - CIVILIAN AGENCY PLANS || IV. | A. | A Learning Process IV-1 || IV. | B. | Consistency/Uniformity and Agency-level Involvement IV-1 || IV. | C. | Multiple Perspectives and Involvement IV-2 || IV. | D. | Compliance with OMB Bulletin 88-16 IV-2 || IV. | E. | Completeness of the Submission || IV. | F. | IV-3 Level of Aggregation IV-3 || IV. | G. | Agency Overviews and Agencywide Computer Security Framework and Policy IV-4 || IV. | H. | Do the Plans Themselves Represent a Vulnerability? IV-4 Comprehensiveness of System Description IV-4 || IV. | I. J. | System and Information Sensitivity IV-5 || IV. | K. L. | Risk Assessment IV-7 Training and Awareness IV-8 || IV. | M. | Applicable Laws, Regulations, and Guidance . . .

(Comment 93) A few comments state that the requirement to keep records that identify the specific source of each ingredient to a lot of finished product exceeds the intent of the Bioterrorism Act. One comment adds that the language in the Bioterrorism Act clearly authorizes a regulation to require the maintenance of records that show the person from whom a product is received and the person to whom a product is sent. The comment states that there is nothing in the language of the Bioterrorism Act or in its legislative history that would support including a requirement that products received be directly associated with products that are shipped. (Response) FDA does not agree with these comments. Section 306(b) of the Bioterrorism Act expressly states that the Secretary * * * may by regulation establish requirements regarding the establishment and maintenance, for not longer than two years, of records by persons (excluding farms and restaurants) who manufacture, process, pack, transport, distribute, receive, hold, or import food, which records are needed by the Secretary for inspection to allow the Secretary to identify the immediate previous sources and the immediate subsequent recipients of food, including its packaging , in order to address credible threats of serious adverse health consequences or death to humans or animals· (emphasis added).* * * Thus, the Bioterrorism Act clearly gives FDA the authority to determine what records are needed to achieve this objective. The final rule contains those requirements that FDA has determined are necessary to help FDA identify the immediate previous sources and immediate subsequent recipients of food to address credible threats of serious adverse health consequences or death to humans or animals. If FDA cannot immediately narrow its tracing to a specific source, tracing becomes much more difficult and time-consuming, there is an increased risk to consumers, and

some food sources may be unfairly implicated. FDA notes, however, that the final rule (§ 1.345(b)) only requires nontransporters to identify the specific source of each ingredient that was used to make every lot of finished product to the extent such information is reasonably available. (Comment 94) A few comments state that they are not able to provide information that ties the specific source of each ingredient to a lot of the finished product. Several comments agreed with FDA's decision to require identification of the specific source of an ingredient in a finished product only when the information is reasonably available. Some comments request that the agency make clear in the final rule that, in many instances, it will be impossible to identify the specific source of a material that is held in bulk and that multiple sourcing information in recordkeeping is to be anticipated for raw materials that are held in bulk form.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. A microservices-based architecture in applications and service mesh application infrastructure that provides various security services through service proxies has emerged as the widespread application environment for cloud-native applications. With the disappearance of the network perimeter due to the need for ubiquitous access to these applications from multiple remote locations using different types of devices, it is necessary to build the concept of zero trust [1] into this application environment.

- In his opinion, IoT security has not received enough attention, in both consumer and organizational contexts. He noted that the increasing interconnection of systems of all types increases attack surfaces and expands the threat profile. - He identified three core activities that the Office of Management and Budget (OMB) performs that are particularly relevant to federal information system security: - o Overseeing the implementation of Federal Information Security Management Act (FISMA) for non-National Security Systems; he noted that in doing this OMB works closely with the Department of Defense (DoD) and the Director of National Intelligence (DNI) to present consistent guidance across the federal space including the DoD and the intelligence community (IC). - o Overseeing the implementation of cybersecurity policies and standards. He noted that OMB has been taking a more active oversight role and seeking to assist federal organizations in meeting their FISMA responsibilities. - o Ensuring agencies comply with government-wide cybersecurity guidance and legislation, including Binding Operational Directives and Emergency Directives from the Department of Homeland Security's (DHS) Cybersecurity and Infrastructure Security Agency (CISA). - He stated that the scope of 'Federal Information systems includes IoT devices', adding 'I don't think we've had enough conversation on that.' He expressed concern that IoT devices are seen as less impactful or less risky, and cited an example of a networked traffic sign being used as an entry point for a cyber-attack as a 'wake-up call' to the range of concerns that IoT raises. - He emphasized that OMB's work in cybersecurity is guided by a risk management philosophy. He described a 'high-value asset' program intended to assist agencies in identifying and protecting their high-value information system and data, and share solutions across agencies.

(G) From subsection (e)(5) because the requirement that records be maintained with attention to accuracy, relevance, timeliness, and completeness would unfairly hamper the investigative process. It is the nature of law enforcement for investigations to uncover the commission of illegal acts at diverse stages. It is frequently impossible to determine initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. (H) From subsection (e)(8) because the notice requirements of this provision could present a serious impediment to law enforcement by revealing investigative techniques, procedures, and

existence of confidential investigations. (l) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an ongoing investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to that individual, and record amendment procedures for this record system. (J) From subsection (g) because this system of records should be exempt to the extent that the civil remedies relate to provisions of 5 U.S.C. 552 a from which this rule exempts the system. (printed page 14738) (7) System identifier and name. F051 AF JA F, Courts-Martial and Article 15 Records. (i) Exemption. (A) Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principle function any activity pertaining to the enforcement of criminal laws. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(j) (2) from the following subsection of 5 U.S.C. 552a(c)(3) , (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (H) and (I), (e)(5), (e)(8), (f), and (g). (B) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (e)(7)(i)(B).

3.6.3 | Continuous Improvement ... 3.6.3 Continuous Improvement A risk-aware culture should be looking for opportunities for improvement-reinforcing effective practices and adjusting to correct deficiencies.

DoD's harmonization of requirements with other agencies is achieved through compliance with NIST standards. DoD's recognition of the standards of other nations occurs through negotiation of international arrangements and agreements, which is beyond the scope of this rule. The CMMC Program has aligned requirements with NIST standards, and many foreign nations are adopting NIST standards as well. In developing this rule, the DoD worked with standards bodies, removed unique requirements, and aligned new requirements directly with NIST SP 800-171 R2 and select NIST SP 800-172 Feb2021 requirements to reduce and streamline cybersecurity burden across the industry. CMMC Program requirements make no change to existing policies for limits on dissemination of CUI. Comments on information sharing between other agencies or foreign entities are beyond the scope of this rule. The requirement to comply with NIST SP 800-171 was mandated in DFARS clause 252.204-7012. Granting alternatives to that standard is beyond the scope of this rule. Several foreign or international companies submitted comments expressing interest in the rule section pertaining to C3PAO requirements (§ 170.9(b)) and correctly noted that this section does not preclude otherwise qualified foreign companies from achieving C3PAO accreditation. Note that the DoD does permit C3PAO personnel who are not eligible to obtain a Tier 3 background investigation to meet the equivalent of a favorably adjudicated Tier 3 background investigation. DoD will determine the Tier 3 background investigation equivalence for use with the CMMC Program only. c. CMMC Acceptance of Other DIBCAC Assessments Comment: Some commenters either did not understand or objected to the fact that standards acceptance requirements for DIBCAC High Assessments require a score of 110 without POA&Ms. Other comments requested clarity regarding standards acceptance of DIBCAC High Assessments at CMMC Levels 2 and 3. One comment inquired about the programmatic details of DCMA's Joint Surveillance Program. Another comment expressed concerns over disparities between how CMMC C3PAOs and DIBCAC assess, given the fact that DIBCAC assessors are empowered to make risk acceptance decisions on behalf of the Government, whereas C3PAO assessors are not. One commenter questioned the use of the NIST SP 800-171 R2 Cybersecurity FAQs as published in the DoD Procurement Toolbox. Another commenter asked whether C3PAOs assess for compliance with DFARS clause 252.204-7012, paragraphs c-g, as DCMA DIBCAC does in their assessments of OSAs. One commenter suggested that the DIBCAC is not certified to conduct Level 3 assessments and that training requirements for CMMC Level 2 C3PAO assessors should also apply to DIBCAC assessors, or else Level 3 assessments should be conducted by C3PAOs. Response:

The Department understands that regulated entities may be concerned with the anticipated administrative burden and cost of revising their business associate agreements or other written

arrangements to comply with a revised Security Rule. For example, a regulated entity would need to update its business associate agreements to add a provision specifying that the business associate will report to the covered entity [867] that it activated its contingency plan no later than 24 hours after activation of such plan. [868] A regulated entity may have existing contracts that are not set to terminate or expire until after the compliance date for a final rule modifying the Security Rule, and we understand that a six-month compliance period may not provide enough time to reopen and renegotiate all contracts, in addition to ensuring that all regulated entities are compliant with the revised Security Rule. Accordingly, the Department proposes to relieve some of the burden on regulated entities by adding a specified period of transition for certain existing contracts. The Department's authority to provide a transition period is expressed in 45 CFR 160.104(c), which allows the Secretary to establish the compliance date for any modified standard or implementation specification, considering the extent of the modification and the time needed to comply with the modification. [869] Given these considerations, to allow regulated entities enough time to update thousands of existing business associate agreements or other written arrangements, the Department proposes to provide additional time to update the contracts required by 45 CFR 164.314(a)(1) . Specifically, the Department proposes to add new transition provisions under 45 CFR 164.318 to allow regulated entities to continue to operate under certain existing business associate agreements or other written arrangements until the earlier of: (1) the date such contract or other arrangement either is renewed on or after the compliance date of the final rule; or (2) a year after the effective date of the final rule. The additional transition period would be available to regulated entities if both of the following conditions are met: (1) prior to the publication date of the final rule, the covered entity or business associate had an existing business associate agreement or other written arrangement with a business associate or subcontractor, respectively, that complied with the Security Rule prior to the effective date of a final rule revising the Security Rule; and (2) such contract or arrangement would not be renewed or modified between the effective date and the compliance date of the final rule.

All options consider relaxing one provision, or excluding one sector from the recordkeeping requirements. In that way, a comparison of the cost of a policy option with the cost of the baseline yields the marginal cost savings from either relaxing a provision in the baseline, or reducing the coverage by one sector relative to the baseline. The columns containing the absolute amount and percentage cost savings show the savings relative to the baseline. In the final rule reported in table 18 of this document, the provisions requiring lot code information, 4- and 8-hour records access, and short compliance dates are all relaxed to yield cost savings relative to the baseline. Additional cost savings result from excluding the following: (1) Foreign persons, except for foreign persons who transport food in the United States; (2) persons who manufacture, process, pack, transport, distribute, receive, hold, or import food contact substances except the finished container that directly contacts the food; and (3) persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished containers that directly contacts food except for those who place food directly in contact with its finished container. The option to relax the requirements for all records to contain lot code information when feasible saves more costs relative to the baseline than any other option. The cost savings from relaxing the lot code information requirement is approximately \$13 billion in present value terms with a 7 percent discount rate, and \$18 billion with a 3 percent discount rate. Based on detailed information in the comments, requiring lot code information to be contained in all records by retailers and distributors would result in approximately an 80 percent loss in productivity for distributors and retailers. Excluding many foreign persons and relaxing the 4- and 8-hour records access requirement also result in significant cost savings. By excluding all foreign persons except those who transport food in the United States, approximately 225,000 facilities would not have to establish and maintain records relative to the baseline. This exclusion results in a cost savings of approximately \$770 million, or 19 percent, relative to the baseline in present value terms when a 7-percent discount rate is used, and a savings of \$1 billion when a 3 percent discount rate is used. A 24-hour records access requirement results in a cost savings of approximately \$260 million relative to the baseline with a 7-percent discount rate, and \$318 million with a 3-percent discount rate.

2. The procedures at DFARS 232.1004 are modified to eliminate the requirement to first agree on price using customary progress payments and then require consideration if performance-based payments are subsequently negotiated. In addition, contracting officers are encouraged to use both the progress payments and performance based payments clauses and provisions, when considering both types of financing methods. 3. The DFARS clauses 252.232-7012, Performance-Based Payments-Whole-Contract

Basis, and 252.232-7013, Performance-Based Payments-Deliverable Items, are modified to specifically state that it is not necessary to have a Government-unique cost accounting system in order to report incurred costs under the clause. 4. A new paragraph (d) is added in DFARS 252.232-7012 and 252.232-7013 that provides some flexibility with regard to acceptable security, although title to the property described in paragraph (f) of the clause at FAR 52.232-32, Performance-Based Payments, is still the preferred security for receipt of performance-based payments. 5. A new provision is added at DFARS 252.232-7016, Notice of Progress Payments or Performance-Based Payments, to be used in lieu of FAR 52.232-13, Notice of Progress Payments, when the solicitation contains clauses for progress payments and performance-based payments, to explain that only one type of financing will be included in the resultant contract, except as may be authorized on separate orders subject to FAR 32.1003(c).

B. Analysis of Public Comments

1. General Support for the Rule

a. Generally support the rule. Comment: Various respondents expressed general support for the rule, particularly the removal of the requirement to limit PBP financing to costs incurred. One respondent stated that the proposed rule is a significant improvement over the current DFARS, creating a more inviting marketplace for private sector entities and nontraditional defense contractors. Another respondent wholeheartedly supported amending the DFARS to implement section 831 of the NDAA for FY 2017. Response: Noted.

b. Generally oppose the rule. Comment: One respondent stated that this rule is worse than the previous rule (DFARS Case 2017-D019, published 8/24/2018, withdrawn 10/4/2018), and against the original genuine intent of simplification to motivate the performance of the supplier. Another respondent recommended adopting the revisions to the DFARS proposed in DFARS Case 2017-D019 that implement section 831, while disregarding those changes that were outside the scope of section 831.

(Comment 193) Many comments assert that the cost estimates for requiring 4 and 8 hour records access were too low or inappropriate. Comments support this assertion by citing factors ranging from the additional staffing requirements necessary to respond to a records request at such short notice, to the burden of a records access request being dependent on the number of records, and to the length of time covered by the records requested. Some comments state that a 48-hour records access requirement would be reasonable, and some comments state that 24 hours would be reasonable.

(Response) FDA acknowledges the difficulties faced by firms complying with the 4 and 8-hour records access requirements. This final rule requires providing access to records as soon as possible, but no later than 24 hours after an FDA request. The costs for 4 and 8 hours and 24 hours are analyzed as policy options later in this document. In the PRIA, we estimated the records access costs as the costs for planning for a records access request. FDA assumed (printed page 71636) that the 4-and 8-hour response time required would compel business practices to change as firms developed preemptive emergency plans, while a 24-hour response requirement would not compel firms to modify their current business practices. Interviews with FDA traceback personnel suggest that firms are able to comply with a 24-hour records access request. Many comments support the notion that a 24-hour response time is not an unreasonable requirement given current business practices. Consequently, FDA maintains the assumption that a 24-hour records access requirement is reasonable under current business practices and that a 4 and 8 hour records access requirement would require additional planning for a records request. Relaxing the records access requirement from 4 and 8 hours to 24 hours leads to an estimated cost savings relative to the PRIA. The access planning cost estimate assumed that 6 hours of administrative labor per firm (lowered to 3 hours per convenience store firm) would be a one-time requirement for each firm. FDA estimated that new businesses would also have to incur records access costs. As a result of relaxing the records access request time to 24 hours, these costs will no longer be incurred.

5. Additional Records Maintenance and Redesign Costs

The cost estimates assume that the information a covered entity must keep is specified, but that the form or type of system in which those records are maintained is not specified; we expect that firms will collect the additional information not currently included in their existing records. Furthermore, FDA assumes that firms will choose to comply with any new requirements in the manner most economically feasible for them, including modifying shipping or purchase records, such as bills of lading, invoices, or purchase orders.

Steps a regulated entity should consider as part of its decommissioning process include: ensuring technology assets are securely erased and then either securely destroyed or recycled; ensuring that the regulated entity's technology asset inventory is updated to accurately reflect the status of decommissioned technology assets or technology assets slated to be decommissioned; and ensuring that privacy is protected through proper migration to another electronic information system or total destruction of the ePHI. [658] The Department proposes to remove the implementation

specifications for accountability and data backup and storage at 45 CFR 164.310(d)(2)(iii) and (iv). We believe that the accountability provisions would be subsumed and replaced by the proposed standard for technology asset inventory at proposed 45 CFR 164.308(a)(1)(i). Thus, when the proposed new standard and implementation specifications are read together, the written policies and procedures that govern the receipt and removal of technology assets that maintain ePHI into and out of a facility, and the movement of these assets within the facility, should include tracking relevant information in the technology asset inventory. Similarly, we are proposing to delete the specification for data backup and storage because it is redundant to the administrative safeguard on data backups at proposed 45 CFR 164.308(a)(13)(ii)(B). As referenced above, in place of the implementation specifications we are proposing to delete, the Department proposes a new implementation specification at proposed 45 CFR 164.310(d)(2)(iii) that would require a regulated entity to review and test the written policies and procedures related to the implementation specifications for technology assets at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. Such environmental or operational changes may range from new and emerging threats to the confidentiality, integrity, or availability of ePHI (e.g., a new virus) to the adoption of new technology assets by the regulated entity (e.g., a new operating system, new types of workstations). Given the constant evolution of IT and methods for restoring data that has been disposed of or was on electronic media that has been sanitized, the Department believes that it is essential for a regulated entity to at least consider the reasonableness and appropriateness of its policies and procedures for disposal and electronic media sanitation, not only annually, but also in the face of any environmental or operational changes. We expect that pursuant to our proposals to strengthen the standard for risk analysis, a regulated entity would be able to identify such environmental and operational changes before they occur.

4. Request for Comment

The physical security measures for the classified sessions will provide for control of, access to, and dissemination of, the classified information to be presented and will provide for secure storage capability, if necessary.

(5) Disclosure authority at meetings. Authority to disclose classified information at meetings, whether disclosure is by officials of industry or USG, must be granted by the USG agency or activity that has classification jurisdiction over the information to be disclosed. Each contractor that desires to disclose classified information at a meeting is responsible for requesting and obtaining disclosure approvals. Associations are not responsible for ensuring that classified presentations and papers of other organizations have been approved for disclosure. A contractor desiring to disclose classified information at a meeting will:

- (i) Obtain prior written authorization for each proposed disclosure of classified information from the USG agency having jurisdiction over the information involved.
- (ii) Furnish a copy of the disclosure authorization to the USG agency sponsoring the meeting.

(6) Requests to attend classified meetings. Before a contractor employee can attend a classified meeting, the contractor will provide justification for why the employee requires access to the classified information, cite the classified contract or GCA program or project involved, and forward the information to the authorizing USG agency.

(printed page 83346) § 117.17 Subcontracting. (a) Prime contractor responsibilities.

(1) Responsibilities. Before a prime contractor may release or disclose classified information to a subcontractor, or cause classified information to be generated by a subcontractor, a determination that access to classified information will be required and such access serves a legitimate USG requirement for the performance of a classified contract in accordance with § 117.9(a) must be made. Prime contractors are responsible for communicating the appropriate security requirements to all subcontractors.

- (i) A security requirements clause and a Contract Security Classification Specification, or equivalent, will be incorporated in the solicitation and in the subcontract. (See the security requirements clause in the prime contract.)
- (ii) The subcontractor must possess an appropriate entity eligibility determination and a classified information safeguarding capability if possession of classified information will be required.

(A) If access to classified information will not be required in the pre-award phase, prospective subcontractors are not required to possess an entity eligibility determination to receive or bid on the solicitation.

The free, publicly available virtual workshop consisted of a mixture of plenary and breakout sessions 3. The agenda is provided in Table 1. The workshop included a keynote presentation from the U.S. Government Accountability Office (GAO) describing their survey of federal use of IoT technology and an overview from the NIST Cybersecurity for IoT Program's technical lead on potential responses to the comments NIST has received. These sessions were followed by breakout discussions on

various aspects of NIST's proposed approach to revising the documents. The plenary sessions resumed with an overview of NIST's Online Informative References (OLIR) Program, followed by a summation of the breakout sessions provided by their facilitators and closing remarks from the NIST program manager. | References | |-----|-----

-----| | [CATALOG] | National Institute of Standards and Technology (2021) NIST's IoT Cybersecurity Capabilities Catalog . Available at <https://pages.nist.gov/IoT-Device-Cybersecurity-Requirement-Catalogs/> | | [CSF] | National Institute of Standards and Technology (2018) Framework for Improving Critical Infrastructure Cybersecurity, Version 1.1.

A Taxonomic Approach to Understanding Emerging Blockchain Identity Management Systems Loïc Lesavre Priam Varin Peter Mell Michael Davidson James Shook Computer Security Division Information Technology Laboratory January 14, 2020 This publication is available free of charge from: <https://doi.org/10.6028/NIST.CSWP.01142020> <!-- image --> ## Abstract Identity management systems (IDMSs) are widely used to provision user identities while managing authentication, authorization, and data sharing within organizations and on the web. Traditional identity systems typically suffer from single points of failure, lack of interoperability, and privacy issues, such as enabling mass data collection and user tracking. Blockchain technology has the potential to alleviate these concerns: it can support the ability for users to control the custody of their own identifiers and credentials, enabling novel data ownership and governance models with built-in control and consent mechanisms. Hence, blockchain-based IDMSs, which could benefit both users and businesses, are beginning to proliferate. This work categorizes these systems into a taxonomy based on differences in blockchain architectures, governance models, and other salient features. Context is provided for the taxonomy through the description of related terms, emerging standards, and use cases while highlighting relevant security and privacy considerations.

3.2.2 | Unauthorized Data Alteration and Addition... 3.2.2 Unauthorized Data Alteration and Addition Data alteration refers to the process of modifying data before or after it is entered into the system.

The Department proposes to define the term ‘technology asset’ to mean the components of an electronic information system, including but not limited to hardware, software, electronic media, information, and data. In so doing, we would clarify which Security Rule requirements apply to all of the components of electronic information systems as opposed to those that apply only to certain components, and which requirements apply to each particular components and which apply to the entire electronic information system. For example, understanding the risks and vulnerabilities to a regulated entity’s ePHI requires a thorough understanding of the components of its electronic information systems, the electronic information systems themselves, how they are connected, and how ePHI moves through those systems. Thus, by requiring a regulated entity to conduct an inventory of its technology assets and to create a network map of its electronic information systems, we clarify that a regulated entity is obligated to consider not only its electronic information systems as a whole, but also the components within those electronic information systems and their functions. 19. Adding a Definition of ‘Threat’ a. Issues To Address Addressing threats to the confidentiality, integrity, and availability of ePHI is a key function of the Security Rule, but the rule does not define ‘threat.’ The concept of threat also underlies the Department’s proposed definition of ‘risk’ defined above and forms the basis of a key proposed implementation specification associated with the standard for risk analysis. [391] b. Proposal The Department proposes to define the term ‘threat’ to mean any circumstance or event with the potential to adversely affect the confidentiality, integrity, or availability of ePHI. This proposal is similar to NIST’s varying definitions of threat, edited to apply specifically to health care and the type of information addressed by the Security Rule. [392] Under this proposal, we would construe the term to apply broadly to include threats caused by, or existing because of, a variety of circumstances that specifically could affect the security of ePHI. Hackers, malicious insiders, and malicious software are examples of threat sources. 20. Clarifying the Definition of ‘User’ a. Current Provision and Issues To Address The Department first defined the term ‘person’ in the HIPAA Rules as part of the 2003 ‘Civil Money Penalties: Procedures for Investigations, Imposition of Penalties, and Hearings’ interim final rule to distinguish a ‘natural person’ who could testify in the context of administrative proceedings from an ‘entity’ (defined therein as a ‘legal person’) on whose behalf a

(A) The term "commercial use" request refers to a request from, or on behalf of one who seeks information for a use or purpose that furthers the commercial, trade, or profit interest of the requester or the person on whose behalf the request is made. In determining whether a requester properly belongs in this category, Components must determine the use to which a requester will put the documents requested. Moreover, where a Component has reasonable cause to doubt the use to which a requester will put the records sought, or where that use is not clear from the request itself, Components should seek additional clarification from the requester before assigning the request to a specific category. (B) When the Components receive a request for documents for commercial use, they should assess charges which recover the full direct costs of searching for, reviewing for release, and duplicating the records sought. Accordingly, commercial requesters are not entitled to 2 hours of free search time and 100 free pages of reproduction. (C) Commercial requesters are not normally entitled to a waiver or reduction of fees based upon an assertion that disclosure would be in the public interest. However, because use is the exclusive determining criterion, it is possible to envision a commercial enterprise making a request that is not for commercial use. It is also possible that a non-profit organization could make a request that is for commercial (printed page 71864) use. Such situations must be addressed on a case-by-case basis. (ii) Educational, non-commercial scientific institution, or news media . Requesters should indicate a willingness to pay duplication charges in excess of 100 pages if more than 100 pages of records are desired. (A) Educational institution . Fees shall be limited to only reasonable standard charges for document duplication (excluding charges for the first 100 pages) when the request is made by an educational institution whose purpose is scholarly research. The term "educational institution" refers to a pre-school, a public or private elementary or secondary school, an institution of undergraduate higher education, an institution of graduate higher education, an institution of professional education, and an institution of vocational education, which operates a program or programs of scholarly research. Fees shall be waived or reduced in the public interest if the fee waiver criteria are met. (B) Non-commercial scientific institution

A contractor will require each applicant for determination of eligibility for access to classified information who claims U.S. citizenship to provide evidence of citizenship to the FSO or other authorized representative of the contractor. All documentation must be the original or certified copies of the original documents. (1) Any document, or its successor, listed in this paragraph is an acceptable document to corroborate U.S. citizenship by birth, including by birth abroad to a U.S. citizen. (i) A birth certificate certified with the registrar's signature, which bears the raised, embossed, impressed, or multicolored seal of the registrar's office. (ii) A current or expired U.S. passport or passport card that is unaltered and undamaged and was originally issued to the individual. (iii) A Department of State Form FS-240, "Consular Report of Birth Abroad of a Citizen of the United States of America." (iv) A Department of State Form FS-545 or DS-1350, "Certification of Report of Birth." (2) Any document, or its successor, listed in this paragraph is an acceptable document to corroborate U.S. citizenship by certification, naturalization, or birth abroad to a U.S. citizen. (i) A U.S. Citizenship and Immigration Services Form N-560 or N-561, "Certification of U.S. Citizenship." (ii) A U.S. Citizenship and Immigration Services Form 550, 551, or 570, "Naturalization Certificate." (iii) A valid or expired U.S. passport or passport card that is unaltered and undamaged and was originally issued to the individual. (d) Procedures for completing the electronic version of the SF 86, "Questionnaire for National Security Positions." The electronic version of the SF 86 (available at: https://www.opm.gov/forms/pdf_fill/sf86.pdf) must be completed in e-QIP or its successor system by the contractor employee and reviewed by the FSO or other contractor employee(s) who has (have) been specifically designated by the contractor to review an employee's SF 86. The FSO or designee will: (1) Provide the employee with written notification that review of the SF 86 by the FSO or other contractor employee is for adequacy and completeness and information will be used for no other purpose within the entity. The use and disclosure by the U.S. Government, and by U.S. Government contractors operating systems of records on behalf of a U.S. Government agency to accomplish an agency function, of the information provided by the employee on the SF-86 is governed by the Privacy Act of 1974, as amended, and by the routine uses published by the USG in the applicable System of Records Notice. (2) Not share information from the employee's SF 86 within the entity and will not use the information for any purpose other than determining the adequacy and completeness of the SF 86. (e) Fingerprint collection. The contractor will submit fingerprints in accordance with CSA guidance. Contractors will use digital fingerprints whenever possible. (f) Pre-employment eligibility determination action.

DoD received numerous comments about the use of ESPs which do not process, store, or transmit CUI. In response to comments, the DoD has reduced the assessment burden on ESPs. ESP assessment, certification, and authorization requirements in §§ 170.19(c)(2) and (d)(2) have been updated. 20.

CMMC Assessment Scope for Devices and Asset Categorization

a. Asset Categorization

Comment: There were many comments regarding the scoping and treatment of assets when using table 3 to § 170.19(c)(1) and table 5 to § 170.19(d)(1). Several comments asked about when asset categorization occurs, who approves it and how to document it. Two comments questioned the applicability of using NIST SP 800-171 R2 for Specialized Assets. Two comments suggested modifying the definition of Out-of-Scope assets by removing the last bullet or discussing the use of encryption. One commenter suggested adding more detailed definitions of the asset categories to the rule. One comment recommended removing asset categories from the rule. Many comments requested scoping and categorization of specific scenarios, such as ERP systems, MRP systems, quantum computing systems, data diodes, asset isolation, and encrypted CUI. Numerous additional comments requested clarification on scoping and categorization of various security product classes.

Response: The OSA performs asset categorization and documents it in their SSP. The OSA may choose the format and content of its SSP. Table 3 to § 170.19(c)(1) requires that all asset categories, including Specialized Assets, be included in the asset inventory. There is no requirement to embed every asset in the SSP. In the SSP for Level 2, the OSA must show how Specialized Assets are managed using the contractor's risk-based security policies, procedures, and practices. Prior to the conduct of an assessment, the OSC engages with the C3PAO assessor. It is during this time that the classification of assets should be agreed upon, and the results of these discussions are documented in pre-planning materials. This is an example of the pre-assessment and planning material submitted by the C3PAO as required in § 170.9(b)(8) and the CMMC Assessment Scope submitted to eMASS as required in § 170.17(a)(i)(D). It is beyond the scope of this rule to address DoD review of specific Specialized Assets for individual contractors.

Additionally, consistent with the Department's proposal to require that a regulated entity provide role-based security awareness training on its Security Rule policies and procedures, [649] the Department expects that such training would address the physical safeguards it has implemented, particularly those policies and procedures for mobile devices that are used to create, receive, maintain, or transmit ePHI or that otherwise affect the confidentiality, integrity, or availability of ePHI.

d. Section 164.310(d)(1)-Standard: Technology Asset Controls

The Department proposes to modify the standard at 45 CFR 164.310(d)(1) by changing the heading to "Technology asset controls" from "Device and media controls," and replacing "hardware and electronic media" in 45 CFR 164.310(d)(1) and (2) with "technology assets." We believe that this modification would more accurately capture the various categories of components of a regulated entity's relevant electronic information systems that may be received in, removed from, or moved within a facility and that also affect the confidentiality, integrity, or availability of ePHI. Thus, we believe that this modification would provide regulated entities with a clearer understanding of their compliance obligations with respect to the physical safeguards that should be implemented to protect ePHI when technology assets are received by, removed from, or moved within a facility. While we are not proposing other significant changes to 45 CFR 164.310(d)(1) at this time, we remind regulated entities to consider the appropriateness of the policies and procedures they have implemented with respect to the movement of technology assets that maintain ePHI into and out of their facilities and the movement of these items within their facilities. The processes a regulated entity chooses to implement to govern the movement of technology assets may vary based on the type of technology asset. [650] For example, once installed, a server or desktop computer may not need to be moved for the entirety of its lifecycle within the regulated entity, while portable electronic devices and media, such as smartphones, tablets, and USB flash drives are designed to be mobile and may move frequently into, out of, and within a regulated entity's facilities. [651] Thus, the regulated entity's policies and procedures must account for these differences. [652] Further, we note that the proposed definition of workstation includes mobile devices. Mobile devices that serve as workstations are subject to the requirements in this paragraph and those in paragraphs (b) and (c). The Department also proposes to modify the standard at 45 CFR 164.310(d)(1)

There were no comments on this issue; however, FDA has deleted the word "domestic" and instead defines the word "person" consistent with its definition in section 201(e) of the FD&C Act. FDA believes that the term "domestic person" is no longer needed because it is exempting foreign persons, except for foreign persons who transport food in the United States, from the requirements

of subpart J of this final rule. 4. Farm (Comment 67) Several comments assert that FDA's proposed definition of farm is too narrow and would require recordkeeping by farms that minimally process their produce for further marketing. The comments claim that many fresh produce farms incorporate packing and holding activities, and that minor manufacturing/processing activities should be considered incidental to the packing and storage activities. Accordingly, to give effect to the legislative intent to exclude farms, the comments argue that the definition of "farm" should include typical fresh produce post-harvest farming operations such as packing/packaging, washing, grading, waxing, sizing, cooling, application of inventory control items (e.g., price lookup stickers (PLUs) or universal product codes (UPCs)), conventional storage, controlled-atmosphere storage, transportation from the fields, transportation to storage or processing facilities, and transportation from the farm. According to the comments, these activities should be included in the definition of "farm" whether they are conducted in the field or in a packinghouse. Some comments believe that the proposed definition of "farm" should be modified to include certain of the activities defined as manufacturing/processing, regardless of whether the foods that are the focus of these activities are consumed on that farm or one with common ownership or are offered for sale elsewhere, at least insofar as these activities relate to raw agricultural commodities. The comments state that the specific manufacturing/processing activities that should be included within the definition of "farm" are at least the following activities: Cutting, at least when this activity is applied to harvest of a farm crop; trimming; washing; labeling, at least when this activity is applied to containers that are not intended for direct consumer purchase; and packaging, at least when this activity is applied to containers that are not intended for direct consumer purchase. The comments also suggest that FDA should consider allowing farms to engage in milling and grinding without voiding the statutory exemption to section 306 of the Bioterrorism Act granted to farms, insofar as these activities are common farm activities.

According to hitech_omnibus_2013: <unknown> ## DEPARTMENT OF HEALTH AND HUMAN SERVICES
Office of the Secretary 45 CFR Parts 160 and 164 ## RIN 0945-AA03 Modifications to the HIPAA
Privacy, Security, Enforcement, and Breach Notification Rules Under the Health Information
Technology for Economic and Clinical Health Act and the Genetic Information Nondiscrimination Act;
Other Modifications to the HIPAA Rules AGENCY: Office for Civil Rights, Department of Health and
Human Services. ACTION: Final rule. SUMMARY: The Department of Health and Human Services (HHS or
"the Department") is issuing this final rule to: Modify the Health Insurance Portability and
Accountability Act (HIPAA) Privacy, Security, and Enforcement Rules to implement statutory
amendments under the Health Information Technology for Economic and Clinical Health Act ("the
HITECH Act" or "the Act") to strengthen the privacy and security protection for individuals'
health information; modify the rule for Breach Notification for Unsecured Protected Health
Information (Breach Notification Rule) under the HITECH Act to address public comment received on
the interim final rule; modify the HIPAA Privacy Rule to strengthen the privacy protections for
genetic information by implementing section 105 of Title I of the Genetic Information
Nondiscrimination Act of 2008 (GINA); and make certain other modifications to the HIPAA Privacy,
Security, Breach Notification, and Enforcement Rules (the HIPAA Rules) to improve their workability
and effectiveness and to increase flexibility for and decrease burden on the regulated entities.
DATES: Effective date: This final rule is effective on March 26, 2013. Compliance date: Covered
entities and business associates must comply with the applicable requirements of this final rule by
September 23, 2013. FOR FURTHER INFORMATION CONTACT: Andra Wicks 202-205-2292. SUPPLEMENTARY
INFORMATION: VerDate Mar<15>2010 18:57 Jan 24, 2013 Jkt 229001 sroberts on DSK5SPTVN1PROD
with ## I. Executive

- protecting the accountability, availability, integrity and confidentiality of information; -
Security management support documentation, including terminology and guidelines as well as
procedures for the registration of security components; - Security aspects of identity management,
biometrics and privacy; - Conformance assessment, accreditation and auditing requirements in the
area of information security management systems; and - Security evaluation criteria and methodology.
The FISMA Team also collaborated with DOD, the IC, DHS, the National Archives and Records
Administration (NARA), the Federal Emergency Management Agency (FEMA), the Government Accountability
Office (GAO), the Office of Management and Budget (OMB), the General Services Administration (GSA),
the Small Business Administration (SBA), and the Inspectors General (IGs) on multiple projects to
ensure consistency with FISMA-related guidance and to protect information in a way that is
commensurate with risk. In addition, the FISMA Team served as co-chairs on the Committee on National
Security Systems working groups. In FY 2017, the voting working group will focus its efforts on the

next revision of the VVSG. Based on feedback from the TGDC and election officials around the country, the new revision is expected to address new technologies and election use cases that have become commonplace in election systems. Additionally, the cybersecurity group plans to investigate security considerations and develop guidance in the areas of voter registration, electronic pollbooks, blank ballot delivery, ballot marking, auditing, and election-night reporting.

Consistent with FDA's assumption that the rule will require only small changes to current recordkeeping practices, the findings from the small business model indicate that virtually no small businesses will shut down as a result of this rule. In the Unfunded Mandates section of the PRIA, we also consider the impacts of the proposal on food prices and conclude that any effect would be negligible. E. Estimating the Benefits The benefits from the recordkeeping rule will be from illnesses averted due to faster traceback components of outbreak investigations, and an increased ability to complete investigations that previously would have been prematurely terminated due to poor records quality. Because of this new recordkeeping rule, a greater number of traceback investigations will be completed, and traceback investigations will take less time because of shorter records access times and better records quality. The benefits estimated in this analysis are realized only in the event of a foodborne outbreak (intentional or unintentional) because the probability of a terrorist attack is unknown. However, the estimated costs are incurred at all times regardless of whether there is an outbreak investigation underway, as well as by all facilities, regardless of whether they are implicated in the outbreak. 1. Bioterrorism Considerations Interviews with FDA traceback personnel indicate that traceback and source investigations involving fresh produce find that the contamination often occurs at the farm level (Ref. 2). The interviews suggest that bioterrorism scenarios envision possible intentional contaminations on the farm, in distribution, at processing, and at retail. Moreover, fresh products may be more likely targeted for intentional contamination when they are at intermediate levels of processing than when they are at the farm level. The benefits from the recordkeeping rule are from enhanced food safety and enhanced food security. We can estimate the food safety benefits, but we cannot estimate the food security benefits, as the probability of the occurrence of a deliberate outbreak is unknown. The tangible benefits from the recordkeeping rule occur after an outbreak of food-related illness. With the records required by this rule, the agency can investigate outbreaks more quickly and will not be forced to terminate an investigation because of poor or nonexistent records. The speeding up of investigations generates benefits in some cases because the information from the records will enable the agency to take actions to reduce the size of the outbreak. Both the increased completion rate and faster investigations may reveal more sources of outbreaks and help to prevent recurrences.

The OSC shall retain the hashed artifacts used as evidence during the assessment process. The OSC shall retain the unedited artifacts for the duration of the validity period of the certificate of assessment, and at a minimum, for six (6) years from the date of certification assessment. To ensure that the artifacts have not been altered, the OSC must hash the artifact files using a NIST-approved hashing algorithm. Assessors will collect the list of the artifact names, the return values of the hashing algorithm, and the hashing algorithm used and upload that data into the CMMC instantiation of eMASS. Additional guidance for hashing artifacts can be found in the guidance document listed in paragraph (h) of appendix A to this part. (5) Assessment of Cloud Service Provider. An OSC may use a Federal Risk and Authorization Management Program (FedRAMP) Moderate (or higher) cloud environment to process, store, or transmit CUI in execution of a contract or subcontract with a requirement for CMMC Level 3 under the following circumstances: (i) The Cloud Service Provider's (CSP) product or service offering is FedRAMP Authorized at the FedRAMP Moderate (or higher) baseline in accordance with the FedRAMP Marketplace; or (ii) The Cloud Service Provider's (CSP) product or service offering is not FedRAMP Authorized at the FedRAMP Moderate (or higher) baseline but meets security requirements equivalent to those established by the FedRAMP Moderate (or higher) baseline. Equivalency is met if the OSC has the CSP's System Security Plan (SSP) or other security documentation that describes the system environment, system responsibilities, the current status of the Moderate baseline controls required for the system, and a Customer Responsibility Matrix (CRM) that summarizes how each control is MET and which party is responsible for maintaining that control that maps to the NIST SP 800-171 Rev 2 requirements. (See https://www.fedramp.gov/assets/resources/documents/FedRAMP_Moderate_Security_Controls.xlsx .) (iii) In accordance with § 170.19, the OSC's on-premises infrastructure connecting to the CSP's product or service offering is part of the CMMC Assessment Scope. As such, the security requirements from the CRM must be documented or referred to in the OSC's SSP. § 170.19 CMMC scoping. (a) Scoping requirement. (1) The CMMC Assessment Scope must be specified prior to assessment in

accordance with the requirements of this section. The CMMC Assessment Scope is the set of all assets in the OSA's environment that will be assessed against CMMC security requirements. (2) The requirements for defining the CMMC Assessment Scope for CMMC Levels 1, 2, and 3 are set forth in this section. Additional guidance regarding scoping can be found in the guidance documents listed in paragraphs (e) through (g) of appendix A to this part. (b) CMMC Level 1 Scoping. Prior to performing a Level 1 CMMC Level 1 Self-Assessment, the OSA must specify the CMMC Assessment Scope. (1)

without unreasonable delay, but no later than 24 hours after activation. [836] This proposal, if finalized, would not alter the business associate's breach reporting obligations under the Breach Notification Rule. [837] The Department believes that it is necessary to notify the covered entity in a timely manner of the contingency plan activation because of the downstream implications for such activation. Receiving such prompt notice could enable the covered entity to take the necessary steps to protect its own relevant electronic information systems, as well as to implement its own contingency plan if necessary and appropriate (e.g., enable the covered entity to access a remote or offline backup of its ePHI if necessary to ensure that patient care is unaffected or to reduce the effect on patient care as much as possible). For example, in 2020, a software company was the target of an attack that used software containing malware to infiltrate the electronic information systems of subsequent users of the software. This allowed cybercriminals to gain access to several government systems and thousands of private systems worldwide. [838] Requiring a business associate to provide prompt notice to the covered entity when the business associate activates its contingency plan could enable regulated entities to maintain individuals' confidence in their commitment to protecting the confidentiality, integrity, and availability of ePHI in the event of an emergency or other occurrence that adversely affects relevant electronic information systems. [839] Additionally, the modified standard would align with the enhanced CPG for Third Party Incident Reporting because this proposal would require a business associate to both report to a covered entity or another business associate activation of its contingency plan within 24 hours of such activation and report known or suspected security incidents. [840] As discussed above, the Department proposes to require a regulated entity to activate its contingency plan to respond to an emergency or other occurrence that adversely affects relevant electronic information systems. [841] The Department believes that regulated entities activate their contingency plans infrequently because such plans are only activated when there is an emergency or other occurrence that rises to a level beyond a security incident that is thwarted or other event that does not adversely affect the confidentiality, integrity, or availability of ePHI. Thus, the need to make the proposed notification would also arise infrequently. For example, a business associate may not be required to notify a covered entity within a certain time after a relevant electronic information system receives a basic internet command such as a ping, [842]

sed on conversations he had with colleagues in which he learned 'each manufacturer is actually just borrowing security APIs instead of creating their own, and the APIs specifically have holes in them. So the same vulnerability is being propagated across vendors' (P13_A) . Others were concerned based on their exposure to news stories about smart home devices being compromised. For P34_A, one such story prompted him to be more suspicious of his devices:

1. Name of the project, and a description of the purpose and scope. 2. Mission requirement the system is designed to satisfy. 3. Estimated costs (capital investment and operations) for each fiscal year 1989-1993. 4. Description of input (typewritten text, invoices, receipts, forms, drawings, etc.). If practical, attach examples of documents that illustrate the various types of information that 5. will be captured. For example, if documents contain both text and image, provide a sample of that type of document. 5. Description of the origin of the input including both the type and location of organizations supplying the documents and the technology that the supplier uses to create the documents, if known 6. Description of the conversion and input process, including scanning system, authentication procedures, use of outside contractors, quality control and data loading procedures. 7. Proposed accuracy of stored image (150 dots per inch, 200 dots per inch, etc.). 8. Storage format for images (Group 4 FAX, etc.). 9. Description of proposed work station for retrieval (including screen resolution, number and size of screens, communications speed and protocol, zoom, local storage capacity, etc.). 10. Volume of stored images (in pages and bytes) to be captured initially, total volume online each year FY 1989-1993, volume removed from online access (archived or destroyed) each year FY 1989-1993. 11. Response time for online document retrieval. 12. Brief description of the operation of the indexing and storage system (index keys, searching

techniques, off-the-shelf system, etc.) 13. A description of unique functions, capabilities, or performance standards (such as large format hardcopy output, grey scale image enhancement, etc.) required by this system that will make it different from commercially available systems. 14. The name and telephone number of a point of contact who can provide more information.

The type of security requirement is noted in the discussion section of each requirement. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025
Appropriately scoping security requirements is an important factor in determining protection-234

(G) From subsection (e)(5) because the requirement that records be maintained with attention to accuracy, relevance, timeliness, and completeness would unfairly hamper the investigative process. It is the nature of law enforcement for investigations to uncover the commission of illegal acts at diverse stages. It is frequently impossible to determine initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. (H) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to the individual and record amendment procedures for this record system. (I) From subsection (g) because this system of records should be exempt to the extent that the civil remedies relate to provisions of 5 U.S.C. 552 a from which this rule exempts the system. (6) System identifier and name. LDIA 10-0002, Foreign Intelligence and Counterintelligence Operation Records. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (b)(6)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) The specific sections of 5 U.S.C. 552 a from which the system is to be exempted are 5 U.S.C. 552a (c)(3) and (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), (H), and (I), (e)(5), (f), and (g). (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons.

Removing from paragraph (b)(2) ·Industrial Security Regulation (DOD 5220.22-R)· and adding ·DoD Manual 5220.22, Volume 2, ·National Industrial Security Program: Industrial Security Procedures for Government Activities...· in its place; and c. Redesignating paragraph (d) as (e), and adding a new paragraph (d) to read as follows: 4.402 General. * * * * * (d) Nondefense agencies that have industrial security services agreements with DoD, and DoD components, shall use the DD Form 254, Contract Security Classification Specification, to provide security classification guidance to U.S. contractors, and subcontractors as applicable, requiring access to information classified as ·Confidential·, ·Secret·, or ·Top Secret·. (1) Provided that the data submittal is unclassified, the DD Form 254 shall be completed electronically in the NISP Contract Classification System (NCCS), which is accessible via the Procurement Integrated Enterprise Environment (PIEE) at <https://wawf.eb.mil> unless a nondefense agency has an existing DD Form 254 information system. (2)(i) A contractor, or subcontractor (if applicable), requiring access to classified information under a contract shall be identified with a Commercial and Government Entity (CAGE) code on the DD Form 254 (see subpart 4.18 for information on obtaining and validating CAGE codes). (ii) Each location of contractor or subcontractor performance listed on the DD Form 254 is required to reflect a corresponding unique CAGE code for each listed location unless the work is being performed at a Government facility, in which case the agency location code shall be used. (iii) Contractor and subcontractor performance locations listed on the DD Form 254 are not required to be separately registered in the System for Award Management (SAM) solely for (printed page 33204) the purposes of a DD Form 254 (see subpart 4.11 for information on registering in SAM). * * * * * 5. Amend section 4.403 by removing from paragraph (c) introductory text ·contract as follows· and adding ·contract as identified in the requirement documentation as follows· in its place, and revising paragraph (c)(1) to read as follows: 4.403 Responsibilities of contracting officers. * * * *

* (c) * * * (1) Nondefense agencies that have industrial security services agreements with DoD, and DoD components, shall use the Contract Security Classification Specification, DD Form 254. The contracting officer, or authorized representative, is the approving official for the DD Form 254 associated with the prime contract and shall- (i) Ensure the DD Form 254 is properly prepared and distributed; and (ii) Coordinate with requirements and security personnel in accordance with agency procedures to complete the DD Form 254, including when completed in the NCCS accessible via the Procurement Integrated Enterprise Environment (PIEE) at <https://wawf.eb.mil> unless a nondefense agency has an existing DD Form 254 information system. * * * * 4.1801 [Amended] 6.

In 2013, the Department issued the final rule ·Modifications to the HIPAA Privacy, Security, Enforcement, and Breach Notification Rules Under the Health Information Technology for Economic and Clinical Health [HITECH] Act and the Genetic Information Nondiscrimination Act, and Other Modifications to the HIPAA Rules· (·2013 Omnibus Rule·), [99] which implemented applicable provisions of the HITECH Act to strengthen security protections for individuals' health information maintained in EHRs. For example, the Department modified the Security Rule to implement the HITECH Act's provisions that extended direct liability for compliance with the Security Rule to business associates. [100] We explained that before the enactment of the HITECH Act, the Security Rule did not directly apply to business associates of covered entities. The HITECH Act extended the application of the Security Rule's administrative, physical, and technical safeguards requirements, as well as the rule's policies and procedures and documentation requirements, to business associates in the same manner as the requirements apply to covered entities, making those business associates civilly and criminally liable for violations of the Security Rule. [101] The Department noted that the Security Rule requires a covered entity to establish business associate agreements that obligate business associates to implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the ePHI that they create, receive, maintain, or transmit on behalf of the covered entity. [102] Accordingly, we reasoned that business associates and subcontractors should already have security practices in place that comply with the Security Rule, or require only modest improvement to come into compliance with the Security Rule requirements. [103] Like the 2003 Final Rule, [104] the 2013 Omnibus Rule highlighted that the Security Rule was designed to be technology neutral and scalable and reiterated that regulated entities have the flexibility to choose security measures appropriate for their size, resources, and the nature of the security risks they face. [105] Accordingly, regulated entities have the flexibility to choose appropriate security measures considering their size, capabilities, the costs of the specific security measures, and the operational impact, enabling them to reasonably implement the standards of the Security Rule. The Department also adopted technical revisions to 45 CFR 164.306(e) to clarify that regulated entities must review and modify security measures as needed to ensure reasonable and appropriate protection of ePHI, and update documentation of security measures accordingly. [106]

(Comment 99) Several comments request that the agency clarify the term ·ingredient· with respect to distilled spirits that have innumerable sources of ingredients dependent upon the category and particular brand. The comments state that there is a question of interpretation as to what is meant by ingredients, given that the distilling process changes substantially the character and chemical composition of the raw materials and some of them may even be absent from the final product. (Response) Alcoholic beverages are within the definition of ·food· in §1.328 of this final rule. A manufacturer of alcoholic beverages is required under §1.337 of this final rule to identify the source of each ingredient that was received to make the alcoholic beverage, regardless of whether it later changes character and chemical composition. (Comment 100) One comment suggests that the agency reconsider the requirement for immediate previous sources of bottled water. The comment asserts that the detail of records required under the regulations will not exist in many cases because the bottled water source will be directly out of the ground and that the bottler will capture any potential concerns of a serious threat of adverse health consequences. The comment suggests that water be viewed as other primary agricultural food ingredients. (Response) Bottled water is within the definition of food as defined in §1.328 of this final rule. If water is obtained from a public water system, then the public water system is the immediate previous source. If ground water is used, then the location where the water was extracted should be provided. (Comment 101) One comment recommends that, in requiring a record of the raw material of a product, the agency should limit its requirement to that of major ingredients of the product. (Response) FDA does not agree with the comment. The comment neither explains what distinguishes a major ingredient from a minor one, nor why the agency should limit its requirement to ·major· ingredients only. Even

if an ingredient is present only in small quantities, it may pose a risk and could be the focus of an intentional attack (e.g., the deliberate addition of a chemical toxin or pathogens), which would further contaminate food products to which they are added. 3. Requirement to Record Responsible Individual

The respondent's recommendation would require reprogramming of the Plant Clearance Automated Redistribution and Screening System (PCARSS). The cost of such reprogramming would largely offset the marginal increase in reutilization realized. C. Sales of Surplus Property Comment: In reference to 245.604-3, Sale of surplus property, a respondent suggested that risk-based techniques be used. For example, high value items should be treated differently, according to the respondent, from items with little potential for proceeds. DoD Response: The language at 245.604-3(1) has been clarified to ensure that plant clearance officers consider the market potential of items prior to authorizing surplus sales and determine the best value sales approach. Comment: A respondent recommended that 252.245-70XX(c), be changed to read 'net proceeds.' The respondent cited the Federal Property Administration Act of 1949, which states that a portion of the proceeds goes to the 'cost of the work.' The respondent also claimed that paragraph (c) conflicts with FAR 31.201-5 and ASTM International standard 2279-09, Establishing the Guiding Principles of Property Management (costs of sales may outweigh the return). DoD response: The respondent's recommendation implies that contractors are entitled to a share of sales proceeds to cover the contractor costs of conducting the sale. There is no basis for such policy or for otherwise directly reimbursing a contractor for costs incurred in conducting surplus property sales. Such action is a normal part of contractor responsibilities under the clause at FAR 52.245-1(b)(2). FAR 31.201-5 pertains to income, rebates, allowances, or other credits made to allowable costs. Because surplus property sales are a normal part of a contractor's property management responsibilities under the clause at FAR 52.245-1(b)(2) and are typically provided by the contractor as an overhead function, FAR 31.201-5 has no application here. ASTM International standard 2279-09 is not germane to the issue of proper deposit of sales proceeds received under surplus sales. Comment: A respondent recommended that a certification statement or a standard form providing the terms and conditions of the sale between the Government and buyer be provided at 252.245-70XX(e). The respondent also asked what the expectation is here. DoD Response: The language exists today in 245.604. As indicated in the proposed rule, 245.604 has been updated and the language moved to the final rule clause at 252.245.70XX. Its requirements are an important policy safeguard to ensure the integrity of the surplus sales process. Comment: A respondent requested that the language at 252.245-70XX(l)(2) be changed as follows, '(t)he Contractor shall solicit a sufficient number of bidders to obtain adequate competition and use informal invitations for bid unless the plant clearance officer approves use of formal bid procedures.' DoD Response:

In FY2013, CSD will assist the EAC in developing responses to public comments and provide updates to VVSG 1.1 and the associated security test suites. CSD will continue to support the efforts for the EAC and FVAP to improve the voting process for UOCAVA voters. CSD will also continue to expand on research activities, particularly in the areas of risks to voting systems and innovative voting system architectures. NIST continue its HIT security outreach efforts. NIST and the Department of Health and Human Services' (DHHS) Office for Civil Rights (OCR) cohosted the fifth annual HIPAA Security Rule conference, 'Safeguarding Health Information: Building Assurance through HIPAA Security,' in June 2012 at the Ronald Reagan Building and International Trade Center in Washington, D.C. The conference offered important sessions that focused on broad topics of interest to the healthcare and health IT security community. Over 500 attendees from federal, state, and local governments, academia, HIPAA-covered entities and business associates, industry groups, and vendors heard from, and interacted with, healthcare, security, and privacy experts on technologies and methodologies for safeguarding health information and for implementing the requirements of the HIPAA Security Rule.

- Employ administrative, physical, and technical safeguards on plant systems.
- Implement acquisitions management, change controls, and obsolescence and lifecycle management.
- Maintain product integrity through continuous quality testing, monitoring containment and shipments, and equipment inspection.
- Establish procedures for integrity measurement, including:
 - o Systems testing
 - o Preventive maintenance
 - o Remediation
 - o Ongoing situational awareness
 - o Process review
- Architect fault-tolerant systems to maintain operational integrity during adverse events.
- Define policy to outline standard operating procedure to maintain repeatable processes with anticipated outcomes.
- Determine a schedule and develop a plan for efficacy measures, which

include testing, preventative maintenance, remediation, and ongoing situational awareness. - Establish and leverage communication paths and trend data from devices to identify deviations from baseline traffic flows. - Document training and awareness procedures for potential cybersecurity risk vectors. Organizations mitigate supply chain risks in the procurement of information and communications technology and services through clear vendor agreements and established processes and procedures (including testing) prior to installation and updates.

3.2.2 | Organization Size... 3.2.2 Organization Size Organization size was determined by the number of federal employees.

and Vincent Rijmen. The Design of Rijndael - The Advanced Encryption Standard (AES), Second Edition . Information Security and Cryptography. Springer, 2020. <https://doi.org/10.1007/978-3-662-60769-5>. - [4] Michael Artin. Algebra . Pearson Modern Classic. Pearson, second edition, 2017. - [5] Alfred J. Menezes, Scott A. Vanstone, and Paul C. Van Oorschot. Handbook of Applied Cryptography . CRC Press, Inc., USA, 1st edition, 1997. <https://doi.org/10.1201/9780429466335>. - [6] Elaine Barker, Allen Roginsky, and Richard Davis. Recommendation for Cryptographic Key Generation. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-133, Rev. 2, June 2020. <https://doi.org/10.6028/NIST.SP.800-133r2>. - [7] National Institute of Standards and Technology. AES Development, 2022. Available at <https://csrc.nist.gov/projects/aes>. - [8] National Institute of Standards and Technology. Cryptographic Standards and Guidelines: Examples with Intermediate Values, 2022. Available at <https://csrc.nist.gov/projects/cryptographic-standards-and-guidelines/example-values>. - [9] National Institute of Standards and Technology. Crypto Publications Review Board, 2022. Available at <https://csrc.nist.gov/projects/crypto-publication-review-project>. - [10] Nicky Mouha. Review of the Advanced Encryption Standard. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Interagency Report (IR) 8319. <https://doi.org/10.6028/NIST.IR.8319>.

(B) Records maintained solely for statistical research or program evaluation purposes and which are not used to make decisions on the rights, benefits, or entitlement of an individual except for census records which may be disclosed under 13 U.S.C. 8 , may be exempt pursuant to 5 U.S.C. 552a(k)(4) . (printed page 14798) (C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (D) All portions of this system of records which fall within the scope of 5 U.S.C. 552a(k)(2) , (k)(4), and (k)(5) may be exempt from the provisions of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) , (k)(4), and (k)(5). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would place the subject of an investigation on notice that they are under investigation and provide them with significant information concerning the nature of the investigation, thus resulting in a serious impediment to law enforcement investigations. (B) From subsections (d) and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because this system of records is compiled for investigative purposes and is exempt from the access provisions of subsections (d) and (f).

and to revise the redesignated evaluation standard to require the technical and nontechnical evaluation(s) to be in writing and performed to determine whether change in the regulated entity's environment or operations may affect the confidentiality, integrity, or availability of ePHI.

Evaluating the effects of a potential change on a regulated entity's environment or operations, including the effects on the confidentiality, integrity, and availability of ePHI, is a critical step in the change control process. An evaluation serves a similar purpose to a risk analysis. However, while a risk analysis looks at the entirety of a regulated entity's enterprise regularly and in response to a change in the regulated entity's environment or operations, an evaluation looks at a specific change that a regulated entity intends to make before the change is made. Thus, this proposal, if adopted, would ensure that a regulated entity proactively considers whether any risks or vulnerabilities to ePHI or its relevant electronic information systems will be introduced by changes it intends to make to its environment or operations and responds by implementing appropriate safeguards in a timely fashion. [489] We also propose to delete the requirement that the evaluation be performed based initially on the standards implemented under this rule because an evaluation is performed to assess the effect(s) of a planned change on the environment, which can be observed when those effects are compared to the environment reflected in the risk analysis. Additionally, the Department proposes to add two implementation specifications at (printed page 942) proposed 45 CFR 164.308(a)(3)(ii) . The proposed implementation specification for performance at proposed 45 CFR 164.308(a)(3)(ii)(A) would require that a regulated entity conduct the evaluation within a reasonable period of time before making a change to its environment or operations, while the proposed implementation specification for response at proposed 45 CFR 164.308(a)(3)(ii)(B) would require a regulated entity to respond to the evaluation in accordance with its risk management plan. A change in the regulated entity's environment or operations would include, but would not be limited to, the adoption of new technology assets; the upgrading, updating, or patching of technology assets; newly recognized threats to the confidentiality, integrity, or availability of ePHI; a sale, transfer, merger or consolidation of all or part of the regulated entity with another person; a security incident that affects the confidentiality, integrity, or availability of ePHI; and relevant changes in Federal, State, Tribal, and territorial law. NIST guidance provides descriptions of key activities and sample questions that would help regulated entities meet this evaluation standard. [490] They include:

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.13.02E Randomness 1773 E mploy [Assignment: organization-defined techniques] to introduce randomness into organizational operations and assets. DISCUSSION Randomness introduces increased levels of uncertainty for adversaries regarding the actions that organizations take to defend their systems against attacks. Such actions may impede the ability of adversaries to correctly target organizational systems that support critical missions or business functions. Uncertainty may cause adversaries to hesitate before initiating or continuing attacks. Misdirection techniques that involve randomness include performing certain routine actions at different times of day, employing different information technologies, using different suppliers, and rotating the roles and responsibilities of o

3.2.6 Review IT Security The Contractor shall examine sensitive and critical IT systems and data files.

(2) Ensure promises of confidentiality are not automatically given but are used sparingly. Establish appropriate procedures and identify fully categories of individuals who may make such promises. Promises of confidentiality shall be made only when they are essential to obtain the information sought (see 5 CFR part 736). (c) Access to records for which DOD-wide exemptions are claimed. Deny the individual access only to those portions of the records for which the claimed exemption applies. (d) Exempt records. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent that such provisions have been identified and an exemption claimed for the record and the purposes underlying the exemption for the record pertain to the record. (e) DoD-wide exemptions. The following exemptions are applicable to all components of the Department of Defense for the following system(s) of records: (1) System identifier and name. DUSDI 01-DoD Department of Defense (DoD) Insider Threat Management and Analysis Center (DITMAC) and DoD Component Insider Threat Records System. (i) Exemption. This system of records is exempted from subsections (c)(3) and (4); (d)(1), (2), (3) and (4); (e)(1), (2), (3), (4)(G)(H) and (I), (5) and (8); and (g) of the Privacy Act. (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(1) , (2), (4), (5), (6), and (7). (iii) Exemption from the particular subsections. Exemption from the particular subsections is justified for the following reasons: (A) Subsection (c)(3). To provide the subject with an accounting of disclosures of records in this system could inform that individual of the existence, nature, or scope of an actual or potential law enforcement or counterintelligence investigation, and thereby seriously impede law enforcement or counterintelligence efforts by permitting the record

subject and other persons to whom he might disclose the records to avoid criminal penalties, civil remedies, or counterintelligence measures. Access to the accounting of disclosures could also interfere with a civil or administrative action or investigation which may impede those actions or investigations. Access also could reveal the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations. (B) Subsection (c)(4). This subsection is inapplicable to the extent that an exemption is being claimed for subsection (d). (C) Subsection (d)(1).

Under the NIST SP 800-171 DoD Assessment Methodology, each of the 110 security requirements has an assigned point value based on criticality: - **5 points**: Critical controls (most impactful to CUI protection). Examples include multi-factor authentication, encryption, and incident response. - **3 points**: Important controls with moderate impact. Examples include security awareness training and configuration management. - **1 point**: Supporting controls with lower individual impact but still required for compliance. The maximum SPRS score is +110 (all controls implemented). If a 5-point control is not implemented, 5 points are deducted. The minimum possible score is -203. Note: As of February 1, 2026, the DFARS 252.204-7019 requirement to submit Basic self-assessment SPRS scores has been eliminated. However, the scoring methodology is still used for Medium and High assessments under DFARS 252.204-7020.

SI.L2-3.14.4 · Update Malicious Code Protection [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13 254 SI.L2-3.14.4 · UPDATE MALICIOUS CODE PROTECTION [CUI DATA] Update malicious code protection mechanisms when new releases are available. ASSESSMENT OBJECTIVES [NIST SP 800-171A]225 Determine if: [a] malicious code protection mechanisms are updated when new releases are available. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]225 Examine [SELECT FROM: System and information integrity policy; configuration management policy and procedures; procedures addressing malicious code protection; malicious code protection mechanisms; records of malicious code protection updates; system security plan; system design documentation; system configuration settings and associated documentation; scan results from malicious code protection mechanisms; record of actions initiated by malicious code protection mechanisms in response to malicious code detection; system audit logs and records; other relevant documents or records]. Interview [SELECT FROM: System or network administrators; personnel with information security responsibilities; personnel installing, configuring, and maintaining the system; personnel with responsibility for malicious code protection; personnel with configuration management responsibility]. Test [SELECT FROM: Organizational processes for employing, updating, and configuring malicious code protection mechanisms; organizational process for addressing false positives and resulting potential impact; mechanisms supporting or implementing malicious code protection mechanisms (including updates and configurations); mechanisms supporting or implementing malicious code scanning and subsequent actions]. DISCUSSION [NIST SP 800-171 REV. 2]

32 CFR part 117 does not impose additional reporting or recordkeeping requirements under the Paperwork Reduction Act of 1995. Standard Form (SF) 328, ·Certificate Pertaining to Foreign Interests· has been assigned OMB Control Number 0704-0194. E.O. 13132 , ·Federalism· It has been certified that 32 CFR part 117 does not have federalism implications, as set forth in E.O. 13132 . This rule does not have substantial direct effects on: (1) The States; (2) The relationship between the National Government and the States; or (3) The distribution of power and responsibilities among the various levels of Government. List of Subjects in 32 CFR Part 117 Classified information Facility security clearances Foreign ownership, control or influence procedures Security measures Accordingly, 32 CFR part 117 is added to read as follows: (printed page 19470) PART 117·NATIONAL INDUSTRIAL SECURITY PROGRAM Subpart A·[Reserved] Subpart B·[Reserved] Subpart C·Procedures for Government Activities Relating to Foreign Ownership, Control or Influence (FOCI) 117.51 Purpose. 117.52 Applicability. 117.53 Definitions. 117.54 Policy. 117.55 Responsibilities. 117.56 Foreign ownership, control or influence (FOCI). Authority: Executive Order (E.O.) 12829, January 6, 1993, 58 FR 3479 . Subpart A·[Reserved] Subpart B·[Reserved] Subpart C·Procedures for Government Activities Relating to Foreign Ownership, Control or Influence (FOCI) §·117.51 Purpose. This part sets forth industrial security procedures and practices related to Foreign Ownership, Control or Influence (FOCI) for the Department of Defense (DoD) Components, as defined in this part and non-DoD Components, as defined in this part, to ensure maximum uniformity and effectiveness in DoD implementation of the National Industrial Security Program (NISP) established by Executive Order (E.O.) 12829 ·National Industrial Security Program,· (available at <http://www.archives.gov/isoo/policy-documents/eo-12829.html>). §·117.52

Applicability. (a) This part applies to: (1) The DoD Components. (2) The non-DoD Components. When the term Government Contracting Activities (GCAs) is used, it applies to both DoD Components and non-DoD Components. (b) This part does not: (1) Limit in any manner the authority of the Secretary of Defense, the Secretaries of the Army, Navy and Air Force; or the Heads of the Components, as defined in this part, to grant access to classified information under the cognizance of their respective department or agency to any individual or entity designated by them. The granting of such access is outside the scope of the NISP and is governed by Executive Order (E.O.) 13526, "Classified National Security Information," (available at <http://www.archives.gov/isoo/pdf/cnsi-eo.pdf>) and applicable disclosure policies. (2) Limit the authority of a GCA to limit, deny, or revoke access to classified information under its statutory, regulatory, or contractual jurisdiction.

and that is required by Executive Order to be kept classified in the interest of national defense or foreign policy. This exemption is applicable to parts of all systems of records including those not otherwise specifically designated for exemptions herein, which contain isolated items of properly classified information. (b) An individual is not entitled to have access to any information compiled in reasonable anticipation of a civil action or proceeding (5 U.S.C. 552a(d)(5)). (c) No system of records within Department of the Air Force shall be considered exempt under subsection (j) or (k) of the Privacy Act until the exemption rule for the system of records has been published as a final rule in the Federal Register . (d) Consistent with the legislative purpose of the Privacy Act of 1974, the Department of the Air Force will grant access to non-exempt material in the records being maintained. Disclosure will be governed by the Department of the Air Force's Privacy Instruction, but will be limited to the extent that identity of confidential sources will not be compromised; subjects of an investigation of an actual or potential violation will not be alerted to the investigation; the physical safety of witnesses, informants and law enforcement personnel will not be endangered, the privacy of third parties will not be violated; and that the disclosure would not otherwise impede effective law enforcement. Whenever possible, information of the above nature will be deleted from the requested documents and the balance made available. The controlling principle behind this limited access is to allow disclosures except those indicated above. The decisions to release information from these systems will be made on a case-by-case basis. (e) General exemptions. The following systems of records claim an exemption under 5 U.S.C. 552a(j)(2) , with the exception of F090 AF IG B, Inspector General Records and F051 AF JA F, Courts-Martial and Article 15 Records. They claim both the (j)(2) and (k)(2) exemption, and are listed under this part: (1) System identifier and name. F071 AF OSI A, Counter Intelligence Operations and Collection Records. (2) System identifier and name. F071 AF OSI C, Criminal Records. (3) System identifier and name. F071 AF OSI D, Investigative Support Records. (4) System identifier and name. F031 AF SP E, Security Forces Management Information System (SFMIS). (i) Exemption. Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if information is compiled and maintained by a component of the agency which performs as its principle function any activity pertaining to the enforcement of criminal laws. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(j) (2) from the following subsections of 5 U.S.C. 552a(c)(3) , (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4)(G), and (I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons.

· the U.S. Government, is a party to the proceeding or has an interest in such proceeding and, by careful review, the Agency determines that the records are (printed page 72689) both relevant and necessary to the proceeding and the use of such records is therefore deemed by the Agency to be for a purpose that is compatible with the purpose for which the Agency collected the records. Disclosure may be made to the National Archives and Records Administration (NARA) and/or the General Services Administration for the purpose of records management inspections conducted under authority of 44 U.S.C. 2904 and 2906 . Disclosure may be made to the DOJ when: · The Agency or any component thereof; or · any employee of the Agency in his or her official capacity; or · any employee of the Agency in his or her individual capacity where the Agency or the DOJ has agreed to represent the employee; or · the U.S. Government, is a party to litigation or has an interest in such litigation and, by careful review, the Agency determines that the records are both relevant and necessary to the litigation and the use of such records by the DOJ is therefore deemed by the Agency to be for a purpose that is compatible with the purpose for which the Agency collected the records. In the event HHS/FDA deems it desirable or necessary, in determining whether particular records are required to be disclosed under the Freedom of Information Act, disclosure may be made to the DOJ for the purpose of obtaining its advice. J. Policies and Practices for Storing, Retrieving, Accessing, Retaining, and Disposing of Records in the System 1. Storage Records are maintained in hard copy

files, image files, electronic hard drive, file servers, and other electronic data storage devices.

2. **Retrievability** To retrieve information, the system database is typically queried using any of the internal data fields. The data fields encompass any data criterion that is entered into the system including, but not limited to, name, FDA region, credential number (if issued pocket credentials), certificate expiration date, State, program area, or authority.

3. **Safeguards**

a. **Authorized users.** Access is restricted to FDA employees and contractors with a Level 5 or higher clearance who have a need for the records in the performance of their duties.

b. **Procedural and technical safeguards.** Technical controls include identification and authentication of the authorized user, access control, audit and accountability, system and communication protection, timely account disablement/deletion, configuration management, maintenance, system and information integrity, media protection, and incident response. These controls extend to remote users as well.

c. **Physical safeguards.** Physical safeguards include controlled-access buildings where all records (such as diskettes, computer listings, and paper documents) are maintained in secured areas, locked buildings, locked rooms, and locked cabinets.

K. **Retention and Disposal**

In addition, a retail food establishment that employs 10 or fewer full-time equivalent employees is excluded from all of the requirements of this subpart, except the records access provisions for existing records under §§ 1.361 and 1.363. Given the large number of establishments that would be excluded and the significant cost reduction, FDA has analyzed the impact on its ability to efficiently and effectively conduct a tracing investigation to address credible threats of serious adverse health consequences or death. FDA believes the information as to the source of the food of concern sold at these establishments may be obtainable from a larger retail food establishment that is covered by the regulations and sold the same food. Specifically, many of the foods sold at very small retail food establishments are nationally distributed and are also sold at covered retail establishments. If there is an outbreak and product could also be traced to a covered retailer, then FDA could use that retailer's records to identify the source of the food. Moreover, given the relatively small size of the exempted establishments, the exempted establishments are likely to have fewer products and suppliers than other retail establishments and are therefore more likely to be able to provide FDA with source information even if they are exempted from records establishment requirements. With larger retailers, the records of immediate previous sources are more critical to isolating quickly potential sources of food that poses a threat of serious adverse health consequences or death to humans or animals. The exclusion is based on the number of employees at each retail food establishment and not the entire company, which may own numerous retail stores.

(Comment 39) One comment argues that distributors for direct selling companies should be exempt from the requirement to maintain records concerning immediate subsequent recipients. The proposed regulation would have a significant impact on the direct selling industry. Independent distributors sell product not only to consumers, but also to other independent distributors in their network to support each others' businesses and enable them to fulfill customer orders.

(Comment 42) One comment states that, in the case of control state retail operations, keeping detailed information on the immediate subsequent recipients would impose an administrative burden. Although retailers are generally exempt from keeping records pertaining to their customers, the exemption is lost when, as is the case with control states, retail stores sell to other retailers, in this case restaurants, taverns, and bars who subsequently resell the alcoholic beverages being purchased to end-use customers. The retail store transactions are essentially the same type of over-the-counter transactions that take place between the stores and individual consumers. Some information is usually and customarily maintained (e.g., the information pertaining to the licensed purchaser and what is being purchased), although in some cases such information is not generally secured and retained. The comment further notes that some of the information sought (e.g., lot and other product identifiers) is neither generally secured, nor is it maintained.

(Response) Section 1.327(d) of the final rule excludes persons who distribute food directly to consumers from the requirement to establish and maintain records of the immediate subsequent recipients of food. As discussed in response to comment 37 of this document, such sales are excluded because FDA can learn from sickened consumers about the sources of food they purchased or notify consumers generally about food that presents a threat. However, this rationale is not applicable when, as described in the comment, retail stores sell to other retail stores. Under § 1.327(e) of the final rule, persons who operate retail food establishments that distribute food to persons who are not consumers are subject to all of the requirements in subpart J of this final rule. However, for retail food establishments, the requirements in § 1.345 of this final rule to establish and maintain records to identify the nontransporter and transporter immediate subsequent recipients that are not consumers applies as to

only those transactions and only to the extent the information is reasonably available. In addition, a retail food establishment that employs 10 or fewer full-time equivalent employees is excluded from all of the requirements in subpart J of this final rule, except §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) In regard to lot identification numbers, retailers are not required to maintain this information. The final rule only requires that persons who manufacture, process, or pack food record lot or code numbers or other identifiers of that food (and only to the extent this information exists) (§§ 1.337(a)(4) and 1.345(a)(4) of the final rule).

MA.L2-3.7.3 · Equipment Sanitization CMMC Assessment Guide · Level 2 | Version 2.13 149 addition to clearing the data an organization could purge (e.g., degaussing, secure erasing, or disassembling) the data, or even destroy the media (e.g., incinerating, shredding, or pulverizing). Performing one of these activities ensures that the data is extremely hard to recover, thus ensuring its confidentiality. For additional guidance on which specific sanitization actions should be taken on any specific type of media, review the description of the Purge actions given in NIST SP 800-88 Revision 1 · Guidelines for Media Sanitization. Example You manage your organization's IT equipment. A recent DoD project has been using a storage array to house CUI. Recently, the array has experienced disk issues. After troubleshooting with the vendor, they recommend several drives be replaced in the array. Knowing the drives may contain CUI, you reference NIST 800-88 Rev. 1 and determine a strategy you can implement on the defective equipment · processing the drives with a degaussing unit [a]. Once all the drives have been wiped, you document the action and ship the faulty drives to the vendor. Potential Assessment Considerations · Is there a process for sanitizing (e.g., erasing, wiping, degaussing) equipment that was used to store, process, or transmit CUI before it is removed from the facility for off-site maintenance (e.g., manufacturer or contracted maintenance support) [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.7.3

ness processes, users or personnel, or external relationships that the adversary can subsequently employ in support of an attack. || Perform reconnaissance and surveillance of targeted organizations. | Adversary uses various means (e.g., scanning, physical observation) over time to examine and assess organizations and ascertain points of vulnerability. || Perform malware-directed internal reconnaissance. | Adversary uses malware installed inside the organizational perimeter to identify targets of opportunity. Because the scanning, probing, or observation does not cross the perimeter, it is not detected by externally placed intrusion detection systems. || Craft or create attack tools. | Craft or create attack tools. || Craft phishing attacks. | Adversary counterfeits communications from a legitimate/trustworthy source to acquire sensitive information such as usernames, passwords, or SSNs. Typical attacks occur via email, instant messaging, or comparable means; commonly directing users to websites that appear to be legitimate sites, while actually stealing the entered information. || Craft spear phishing attacks. | Adversary employs phishing attacks targeted at high value targets (e.g., senior leaders/executives). || Craft attacks specifically based on deployed information technology environment. | Adversary develops attacks (e.g., crafts targeted malware) that take advantage of adversary knowledge of the organizational information technology environment. || Create counterfeit/spoof website. | Adversary creates duplicates of legitimate websites; when users visit a counterfeit site, the site can gather information or download malware. || Craft counterfeit certificates. | Adversary counterfeits or compromises a certificate authority, so that malware or connections will appear legitimate. || Create and operate false front organizations to inject malicious components into the supply chain.

Homeland Security Presidential Directive 12 (HSPD-12) [4] mandated the development and use of a federal standard for identification and authentication of federal employees and contractors. HSPD-12's intent is to eliminate the 'wide variations in the quality and security of identification used to gain access.' The standard resulting from HSPD-12, Personal Identity Verification (PIV), is defined in Federal Information Processing Standards (FIPS) Publication 201 [5]. FIPS This work resulted in the development of the CSIP [1]. A major gap identified by the CSIP is the delay in utilizing PIV credentials for logical access control and identity management on federal information systems, with an especially high priority for strengthening authentication for The NIST Risk Management Framework (RMF) [12] specifies the security risk management activities that an agency should perform throughout the system development lifecycle. The RMF references the associated standards and guidelines necessary to categorize system risk, select and implement security controls, and assess, monitor, and enhance their efficacy over time.

This publication provides a catalog of security and privacy controls for information systems and organizations to protect organizational operations and assets, individuals, other organizations, and the Nation from a diverse set of threats and risks, including hostile attacks, human errors, natural disasters, structural failures, foreign intelligence entities, and privacy risks. The controls are flexible and customizable and implemented as part of an organization-wide process to manage risk. The controls address diverse requirements derived from mission and business needs, laws, executive orders, directives, regulations, policies, standards, and guidelines. Finally, the consolidated control catalog addresses security and privacy from a functionality perspective (i.e., the strength of functions and mechanisms provided by the controls) and from an assurance perspective (i.e., the measure of confidence in the security or privacy capability provided by the controls). Addressing functionality and assurance helps to ensure that information technology products and the systems that rely on those products are sufficiently trustworthy. Organizations must exercise due diligence in managing information security and privacy risk. This is accomplished, in part, by establishing a comprehensive risk management program that uses the flexibility inherent in NIST publications to categorize systems, select and implement security and privacy controls that meet mission and business needs, assess the effectiveness of the controls, authorize the systems for operation, and continuously monitor the systems. Exercising due diligence and implementing robust and comprehensive information security and privacy risk management programs can facilitate compliance with applicable laws, regulations, executive orders, and governmentwide policies.

This document captures the input received from the half-day workshop titled 'Public Safety Mobile Application Security Requirements' organized by the Association of Public-Safety Communications Officials (APCO) International, in cooperation with FirstNet and the Department of Commerce and held on February 25, 2014. This first-of-its-kind workshop was attended by public safety practitioners, mobile application developers, industry experts, and government officials who contributed their experience and knowledge to provide input in identifying security requirements for public safety mobile applications. This publication was developed as part of the NTIA/NIST Public Safety Communication Research program with sponsorship from the Office for Interoperability and Compatibility (OIC) at the Department of Homeland Security (DHS). The authors would like to thank Jeff Cohen, Jay English, Mark Reddish, and Roger Wespe from Association of Public-Safety Communications Officials (APCO) International, Alex Kreilein from DHS/OEC, as well as the workshop participants for providing valuable feedback on drafts of this document. The authors would like to thank the following organizations for their public comment submissions: Intrado Inc., Secure Access Technologies, and the Mobile EAS Coalition. On February 25, 2014, the Association of Public-Safety Communications Officials (APCO) International, in cooperation with FirstNet and the Department of Commerce held a half-day workshop titled 'Public Safety Mobile Application Security Requirements' attended by public safety practitioners, mobile application developers, industry experts, and government officials. In this first-of-its-kind workshop, attendees contributed their experience and knowledge to provide input in identifying security requirements for public safety mobile applications. The following document describes the workshop and captures the input that was received from the workshop attendees.

Additional information about each asset category is provided in the ensuing sections. Identifying the CMMC Assessment Scope CMMC Assessment Scope · Level 3 · Version 2.13 3 Table 1. Level 3 Asset Categories and Associated Requirements Overview Asset Category Asset Description OSC Requirements CMMC Assessment Requirements Assets that are in the Level 3 CMMC Assessment Scope Controlled Unclassified Information (CUI) Assets o Assets that process, store, or transmit CUI o Assets that can, but are not intended to, process, store, or transmit CUI (defined as Contractor Risk Managed Assets in Table 1 to 32 CFR § 170.19(c)(1)) o Document in the asset inventory o Document asset treatment in the System Security Plan (SSP) o Document in the network diagram of the CMMC Assessment Scope o Prepare to be assessed against CMMC Level 2 and Level 3 security requirements o Limited check against Level 2 and assess against all Level 3 CMMC security requirements Security Protection Assets o Assets that provide security functions or capabilities to the OSC's CMMC Assessment Scope, irrespective of whether or not these assets process, store, or transmit CUI o Document in the asset inventory o Document asset treatment in the SSP o Document in the network diagram of the CMMC Assessment Scope o Prepare to be assessed against CMMC Level 2 and Level 3 security requirements o Limited check against Level 2 and assess against all Level 3 CMMC security requirements that are relevant to the capabilities provided Specialized Assets o Assets that can process, store, or transmit CUI but are unable to

be fully secured, including: Internet of Things (IoT) devices, Industrial Internet of Things (IIoT) devices, Operational Technology (OT), Government Furnished Equipment (GFE), Restricted Information Systems, and Test Equipment

- o Document in the asset inventory
- o Document asset treatment in the SSP
- o Document in the network diagram of the CMMC Assessment Scope
- o Prepare to be assessed against CMMC Level 2 and Level 3 security requirements
- o Limited check against Level 2 and assess against all Level 3 CMMC security requirements
- o Intermediary devices are permitted to provide the capability for the specialized asset to meet one or more CMMC security requirements

Assets that are not in the Level 3 CMMC Assessment Scope

3.2.12 | Risk Acceptance | 20 || 3. 3.2.12 Risk Acceptance Although some participants had concerns, they ultimately made a conscious choice, described as 'willful ignorance' by P1\ _A, to accept privacy and security risks in exchange for perceived benefits.

Control PS-199: fying opportunities for improvement. · Enable agencies to make informed trade-offs concerning the appropriateness of and investments in the cybersecurity of particular organizational units or systems. | Primary SP 800-37 Level: 2 - Mission/Business Processes Primary Cybersecurity Framework Component: Implementation Tiers | |-----

-----|-----

-----| Summary:

Implementation Tiers provide agencies with a basis for rationalizing different aspects of cybersecurity operations across an organization. These decisions are based on trade-off analyses of target Implementation Tiers for various agency business units or specific assets. Gap analysis between the current and Target Implementation Tier will reveal opportunities for prioritizing improvement investments.

ding proactive notification to consumers, retailers, and third parties. Companies should track devices to address critical vulnerabilities and create structured options for off-ramping zombie devices. Higginbotham emphasized that company priorities often overlook device security. Manufacturers should implement vulnerability disclosure programs, track issues, conduct comprehensive security audits, and allocate budgets for security maintenance. Buyers must keep products updated or segmented, and legislation should clarify responsibility to ensure herd immunity. Companies should have a dedicated point of contact for security researchers and consider recalls for insecure devices. Stacey also addressed secure repairs, both before and after end of life. Good hardware should not end up in landfills, but unpatched zombie devices pose risks. Consumer Reports advocates for designing products for longevity, including features like hardware upgrades, crypto agility, and increased memory.

From the NIST SP 800-172 Rev 3 Final Public Draft: generated by scanning, monitoring, or other data collection activities is integrated 894 with the analysis of audit record information. Security information and event management (SIEM) tools can facilitate audit record aggregation or consolidation from multiple system components as well as audit record correlation and analysis. The use of standardized audit record analysis scripts developed by organizations (with localized script adjustments, as necessary) provides more cost-effective approaches to analyzing audit record information. The correlation of audit record information with vulnerability scanning information is important in determining the veracity of vulnerability scans of the system and in correlating attack detection events with scanning results. Correlation with perfor

The respondent commented that certain commands within the Department have created contract-specific requirements mandating that contractors apply the protections and reporting requirements of DFARS 252.204-7012-including the reporting and record-keeping obligations-to categories of information much broader than CDI. The respondent recommends that commercial-item contractors and contractors that do not possess CDI, regardless of contract-specific cybersecurity requirements, be exempt from the reporting and recordkeeping requirements. The respondent further suggests that agencies be required to obtain approval from a centralized office within the Department and to explain the basis

for requiring protections in excess of what is required by DFARS 252.204-7012. Response: Covered defense information is a term used to identify information that requires protection under DFARS clause 252.204-7012 that means unclassified controlled technical information or other information that requires safeguarding or dissemination controls pursuant to and consistent with law, regulations, and Governmentwide policies. When the acquisition of commercial items or services involves (printed page 36907) covered defense information, DFARS clause 252.204-7012 and any additional contract-specific cybersecurity requirements incorporated by the requiring activity will apply to both the solicitation and resulting contract. DFARS 252.204-7012 requires the contractor to provide adequate security on any unclassified information system that is owned, or operated by or for, the contractor and that processes, stores, or transmits covered defense information. Covered defense information, when provided to the contractor, by or on behalf of DoD in support of the performance of the contract, must be marked or otherwise identified in the contract, task order, or delivery order. If a contractor has reason to question whether the information requires protection under this clause, the contractor should consult with the cognizant contracting officer for clarification. DoD agencies follow the Department's policies for information protection contained in DoD Manual (DoDM) 5200.01 Vol 4, DoD Information Security Program: CUI, and in DoD Instruction (DoDI) 5230.24, Distribution Statements on Technical Documents. As these policies have been in place for several years, the Department does not require a centralized office to oversee their execution.

E. Desk Officer Comments and recommendations on the proposed information collection should be sent to Ms. Jasmeet Seehra, DoD Desk Officer, at Oira_submission@omb.eop.gov . Please identify the proposed information collection by DoD Desk Officer and the Docket ID number and title of the information collection. You may also submit comments, identified by docket number and title, to: Federal eRulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments.

F. DoD Clearance Officer

<https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-first-quarter-2022/index.html> . Back to Citation 397. Id. Back to Citation 398. Id.; The National Vulnerability Database is the U.S. government repository of standards-based vulnerability management data. See ·National Vulnerability Database,· National Institute of Standards and Technology, U.S. Department of Commerce, <https://nvd.nist.gov> . Back to Citation 399. ·Known Exploited Vulnerabilities Catalog,· Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security, <https://www.cisa.gov/known-exploited-vulnerabilities-catalog> . Back to Citation 400. · See NIST definition of ·vulnerability,· Glossary, Computer Security Resource Center, National Institute of Standards and Technology, U.S. Department of Commerce, <https://csrc.nist.gov/glossary/term/vulnerability> . Back to Citation 401. ·Proposed 45 CFR 164.308(a)(2)(ii)(A) (7). Back to Citation 402. ·Proposed 45 CFR 164.308(a)(4)(i) . Back to Citation 403. ·Proposed 45 CFR 164.312(h)(1) . Back to Citation 404. 45 CFR 164.304 (definition of ·Workstation·). Back to Citation 405. See, e.g., 45 CFR 164.310(b) and (c) . Back to Citation 406. · See 42 U.S.C. 1320d-2(d) . Back to Citation 407. · See 42 U.S.C. 1320d-2(d)(2)(A) . Back to Citation 408. ·See 42 U.S.C. 1320d-2(d)(2)(B)(i) . Back to Citation 409. · See 42 U.S.C. 1320d-2(d)(2)(B)(ii) . Back to Citation 410. · See 42 U.S.C. 1320d-2(d)(2)(C) . Back to Citation 411. ·The factors are: (1) the technical capabilities of records systems used to maintain health information; (2) the costs of security measures; (3) the need for training; (4) the value of audit trails in computerized record systems; and (5) the needs and capabilities of small and rural health care providers. See 42 U.S.C. 1320d-2(d)(1)(A)(i)-(v) . Back to Citation 412. See University of Texas M.D. Anderson Cancer Center, *supra* note 258, p. 478. Back to Citation 413. 68 FR 8334 , 8343 (Feb. 20, 2003). Back to Citation 414. · See ·What is the difference between addressable and required implementation specifications in the Security Rule?,· Office for Civil Rights, U.S. Department of Health and Human Services, HIPAA FAQ #2020 (Dec. 28, 2022), <https://www.hhs.gov/hipaa/for-professionals/faq/2020/what-is-the-difference-between-addressable-and-required-implementation-specifications/index.html> . Back to Citation 415. · See 45 CFR 164.306(d)(3) ; ·What is the difference between addressable and required implementation specifications in the Security Rule?,· *supra* note 414. Back to Citation 416. ·The Department has consistently attempted to dispel the notion that addressable implementation specifications are optional. See, e.g., ·Security 101 for Covered Entities,· HIPAA Security Series, Centers for Medicare & Medicaid Services, p. 6 (Nov. 2004, revised Mar. 2007), <https://www.hhs.gov/sites/default/files/ocr/pri-vacy/hipaa/administrative/securityrule/security101.pdf?language=-es;>

Back to Citation 8. ·See footnote 1 to §310.1. Back to Citation 9. ·See footnote 1 to

§-310.1. Back to Citation 10. ·See footnote 1 to §-310.1. Back to Citation 1. ·Number used by the Component for reference purposes. Back to Citation 2. ·Indicate the nature of the case, such as, ·Denial of access,· Refusal to amend,· Incorrect records,· or other violations of the Act (specify). Back to Citation [FR Doc. E7-6118 Filed 4-12-07; 8:45 am] BILLING CODE 5001-06-P

When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k) (2) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (H) and (I), and (f). (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(2) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting, for disclosures pursuant to the routine uses published for this system, would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (c)(4) because an exemption is being claimed for subsection (d), this subsection will not be applicable. (C) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (D) From subsection (e)(1) because in the course of criminal investigations information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (E) From subsection (e)(2) because in a criminal investigation the requirement that information be collected to the greatest extent possible from the subject individual would present a serious impediment to law enforcement in that the subject of the investigation would be placed on notice of the existence of the investigation and would therefore be able to avoid detection. (F) From subsection (e)(3) because the requirement that individuals supplying information be provided with a form stating the requirements of subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (G) From subsections (e)(4)(G) and (H) because this system of records is exempt from individual access pursuant to subsections (j) and (k) of the Privacy Act of 1974. (H) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants.

, an individual may submit a request to the FDA Privacy Act Coordinator, with a notarized signature, to confirm whether records exist about him or her. Requests should be directed to the FDA Privacy Act Coordinator, Division of Freedom of Information, 12420 Parklawn Dr., ELEM-1036, Rockville, MD 20857. An individual requesting notification via mail should certify in his or her request that he or she is the individual who he or she claims to be and that he or she understands that the knowing and willful request for or acquisition of a (printed page 67823) record pertaining to an individual under false pretenses is a criminal offense under the Act subject to a \$5,000 fine, and indicate on the envelope and in a prominent manner in the request letter that he or she is making a ·Privacy Act Request.· Additional details regarding notification request procedures appear in 21 CFR part 21, subpart D . RECORD ACCESS PROCEDURES: Procedures are the same as above, in Notification Procedures. Requesters should also reasonably specify the record contents being sought. Some records may be exempt from access under 5 U.S.C. 552a(d)(5) , if they are ·compiled in reasonable anticipation of a civil action or proceeding.· If access to requested records is denied, the requester may appeal the denial to the FDA Commissioner. Additional details regarding record access procedures and identity verification requirements appear in 21 CFR part 21, subpart D . CONTESTING RECORD PROCEDURES: In addition to the procedures described above, requesters should reasonably identify the record, specify the information they are contesting, state the corrective action sought and the reasons for the correction, and provide justifying information showing why the record is not accurate, complete, timely, or relevant. Rules and procedures regarding amendment of Privacy Act records appear in 21 CFR part 21, subpart E . RECORD SOURCE CATEGORIES: Information in this system is obtained from many sources, including: (1) Directly from the individual, company or organization that is required to submit user fees to FDA; (2) from materials supplied by the submitter or individual acting on his/her behalf; (3) from FDA Centers such as the Center for Drug

Evaluation and Research, Center for Devices and Radiological Health, Center for Biologics Evaluation and Research, Center for Veterinary Medicine, Center for Tobacco Products, Center for Food Safety and Applied Nutrition, and the Office of Financial Management; and (4) from any other relevant source. RECORDS EXEMPTED FROM CERTAIN PROVISIONS OF THE PRIVACY ACT: None. Dated: November 7, 2012. Leslie Kux, Assistant Commissioner for Policy. [FR Doc. 2012-27580 Filed 11-13-12; 8:45 am] BILLING CODE 4160-01-P

In the Health Insurance Reform: Standards for Electronic Transactions final rule in 2000, we explicitly adopted a broader definition of standard because we recognized that the statutory definition only applied to standards for financial and administrative transactions, despite the statute's requirement that the Secretary adopt standards addressing other matters, including privacy and security. [321] At that time, we explained that we adopted a broader definition of standard to accommodate the varying functions of the specific standards proposed in other HIPAA regulations. [322] For the same reason, we believe that it is appropriate to continue to rely on the regulatory definition of standard. [323] As discussed above, in both 1998 and 2003, the Department determined that no comprehensive, scalable, and technology-neutral set of standards exists, and accordingly, we proposed and adopted a new standard. [324] In 2013, we made only minor modifications to the standards when we complied with explicit directions from Congress to apply the requirements of the Security Rule to business associates, so we did not need to consider whether an ANSI-accredited standard setting organization had adopted a comprehensive set of standards on the security for ePHI that was flexible, scalable, and technology-neutral. [325] However, because we believe it is appropriate for us to consider modifying the Security Rule at this time for the reasons discussed above, we must again consider whether an ANSI-accredited standards setting organization has developed, adopted, or modified a standard relating to the security of ePHI. The Department continues to believe that any standard must be comprehensive, rather than piecemeal, as recommended by the ANSI Healthcare Informatics Standards Board. [326] We also continue to agree with the recommendation that the standards should be technology-neutral because security technology continues to evolve to keep pace with the evolution of technology more broadly. Additionally, the Security Rule must remain flexible and scalable to allow for consideration of the wide variety of regulated entities, enabling such entities to determine the reasonable and appropriate security measures for their circumstances by taking into account the factors specified by HIPAA. [327] We are not aware of any standard setting organizations that are accredited by ANSI that have issued standards for the security of ePHI, let alone standards that are sufficiently comprehensive, flexible, scalable, and technology-neutral to enable regulated entities to take into account the HIPAA factors. For example, NIST has issued numerous publications addressing health care cybersecurity that are considered by NIST to be guidance, rather than standards. In fact, NIST is ANSI-accredited for only one standard. [328]

For example, the standard for risk analysis proposed in 45 CFR 164.308(a)(2) would protect ePHI from risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI, while the modified standard for workforce security proposed in 45 CFR 164.308(a)(9) would protect ePHI from inappropriate access by a regulated entity's workforce. An invalidated standard for workforce security would not render the entire rule unworkable because a regulated entity could still meet the requirement to conduct the risk analysis without regard to whether the entity meets the requirements included in the standard for workforce security. Similarly, were a court to invalidate the Department's proposal in 45 CFR 164.310(a)(1) requiring that implemented policies and procedures to limit physical access to relevant electronic information systems and the facility or facilities in which they are housed be in writing, a regulated entity could still meet a requirement to implement the policies and procedures. Similar considerations apply to the proposal for written policies and procedures in proposed 45 CFR 164.316(a) , and to proposals that are deemed inapplicable to certain persons or circumstances. Further, the Department believes it is necessary to clarify how regulated entities would continue to apply implementation specifications in the event a court invalidates or deems inapplicable a governing standard over a specific implementation specification, or if a court invalidates or deems inapplicable one or several implementation specifications without taking adverse action on the governing standard. The Department does not interpret that this severability proposal, if finalized, would apply to implementation specifications in the same manner as it would apply to standards. Because the implementation specifications are regulatory instructions on how a regulated entity is to comply with a particular standard, if any standard is stricken, all implementation specifications underneath are similarly stricken. Conversely, the Department does not intend for the overarching standard to be affected by

a court's decision to invalidate or make a determination of non-applicability to particular person or circumstance all implementation specifications under a particular standard. The Security Rule would still retain its flexible and scalable approach, and, therefore, a regulated entity could use any reasonable and appropriate security measure to implement the standard consistent with 45 CFR 164.306(b), even if all implementation specifications under the standard are stricken. If a court invalidates or deems inapplicable less than all implementation specifications under a specific standard (i.e.,

Executive Order (EO) 14028, 'Improving the Nation's Cybersecurity,' tasks the National Institute of Standards and Technology (NIST), in coordination with the Federal Trade Commission (FTC) and other agencies, to initiate pilot programs for cybersecurity labeling. These labeling programs are intended to educate the public on the security capabilities of software development practices. To inform this effort, the EO directs NIST to 'identify secure software development practices or criteria for a consumer software labeling program.' This document seeks to fulfill this directive by making recommendations in the following areas: 1) the role of a scheme owner in a labeling program, 2) baseline technical criteria that can inform a label, 3) labeling presentation criteria, and 4) conformity assessment criteria. This document also explores consumer education and usability for software labels. NIST was directed to 'identify secure software development practices or criteria for a consumer software labeling program' to 'reflect a baseline level of security practices, and if practicable... increasingly comprehensive levels of testing and assessment that a product may have undergone.' This document addresses the need to develop appropriate cybersecurity criteria for consumer software. It also informs the development and use of a label for consumer software. This in turn can improve consumers' ability to take cybersecurity into account when making decisions about software selection and use. The following key recommendations are addressed:

One comment states that FDA should harmonize the Bioterrorism regulations with the other current regulatory provisions such as the Perishable Agricultural Commodities Act, where available. The definition for 'perishable food' should include all fresh fruits and vegetables where the original kind or character has not been changed. The comment states that the effects of the following operations should not be considered as changing a commodity into a food of a different kind or character: Water, steam, or oil blanching; chopping; color adding; curing; cutting; dicing; drying for the removal of surface moisture; fumigating; gassing; heating for insect control; ripening and coloring; removal of seed, pits, stems, calyx, husk, pods, rind, skin, peel, etc.; polishing; precooling; refrigerating; shredding; slicing; trimming; washing with or without chemicals; waxing; adding sugar or other sweetening agents; adding ascorbic acid or other agents used to retard oxidation; mixing several kinds of sliced, chopped, or diced fruits or vegetables for packaging in any type of containers; or comparable methods of preparation. (For example, fresh iceberg lettuce, romaine and carrots would be included, as well as fresh-cut and packaged salads; fresh green beans would be included; frozen or canned green beans would not; fresh oranges would be included; frozen concentrated orange juice would not.) One comment states that the proposed definition of 'perishable food' excludes many products (including milk, which sometimes has a shelflife of up to 15 days) that are handled and treated as perishable in the food distribution system. The comment states that FDA should amend the definition so that perishable foods are those that are refrigerated or those that will be adversely affected if held longer than 20 days. The comment asserts that such a change would make the regulation more consistent with industry practice. One comment states that the 'perishable food' definition is confusing because the definition begins by stating that perishable foods are foods that are 'not heat-treated, not frozen and not otherwise preserved * * *

' Confusion arises because pasteurized milk is heat treated, and FDA's qualification of the three criteria is somewhat awkward and combined with an extensive use of negatives.

A staff IT specialist (IT4-SB) for 48 hours (\$86.24/hr × 48hrs = \$345) Affirmation initial affirmation post assessment: \$1,876 Reaffirmations: It is estimated that the costs to reaffirm a CMMC Level 3 Assessment annually is \$1,876 (three-year cost is \$5,628, or \$1,876 × 3) A director (MGMT5) for 8 hours (\$190.52/hr × 8hrs = \$1,524) A staff IT specialist (IT4-SB) for 4.08 hours (\$86.24/hr × 4.08hrs = \$352) The Level 3 Affirmations cost burden will be addressed as part of the 48 CFR acquisition rule. Summary: The following is the annual small entities total cost summary for CMMC Level 3 Certifications and Affirmations over a ten-year period. Example calculation, Year 2 (reference per entity amounts shown): *(\$9,050 Certification per entity × 45 entities) + (\$1,876 Annual Affirmation per entity × 3 entities) = \$412,897, and \$121,500,000 Nonrecurring Engineering

cost (\$2,700,000 per entity × 45 entities being certified), and \$23,520,000 Recurring Engineering cost (\$490,000 per entity × 45 entities being certified) + (\$490,000 per entity × 3 entities performing affirmations) \$145,432,897 Total Cost = Certification and Affirmation Cost (\$412,897) + Nonrecurring Engineering cost (\$121,500,000) + Recurring Engineering cost (\$23,520,000), or \$145,432,897. (printed page 89111) Relevant Federal rules which may duplicate, overlap, or conflict with the rule. The rule does not duplicate, overlap, or conflict with any other Federal rules. Rather, this rule allows DoD to validate and verify that defense contractors and subcontractors have implemented existing cybersecurity requirements set forth in FAR clause 52.204-21 and in the NIST SP 800-171 Rev 2, which are intended to protect FCI and CUI during contract performance. D. Sec. 202, Public Law 104-4 , ·Unfunded Mandates Reform Act· (2 U.S.C. Chapter 25) The Unfunded Mandates Reform Act requires agencies to assess anticipated costs and benefits before issuing a rule including mandates that require the spending of \$100M dollars or more in a single year (in 1995 dollars and updated for inflation) by State, local, or Tribal governments, in the aggregate, or by the private sector. This rule's impact, if any, on State, local, or Tribal governments, in the aggregate, will not exceed \$100M dollars or more in a single year, and it will not significantly or uniquely affect small governments. This rule is expected to have an impact on the private sector of \$100M dollars or more annually; however, this rule is being published as a national security function of the United States as unauthorized disclosure of FCI or CUI information to parties outside the Department or foreign entities can cause significant harm to the interests of the United States. See the regulatory impact section of the preamble for an assessment of the costs and benefits for this rule. E. Public Law 96-511, ·Paperwork Reduction Act· (44 U.S.C. Chapter 35)

(1) Individual items of unclassified information, when compiled, reveal additional associations or relationships that meet the standard for classification under an existing Executive Order and DoD 5200.1-R, and are not otherwise revealed in the individual items of information. This is known as the ·mosaic·, or ·compilation· approach. (2) The existence or nonexistence of a record would itself reveal classified information. (b) Exemption 2. Pursuant to 5 U.S.C. 552(b)(2) , records related solely to the internal personnel rules and practices of the Department of Defense or any of the DoD Components are exempt from disclosure. This exemption has two profiles, high ·(b)(2)· and low ·(b)(2)·. (1) High ·(b)(2)·. Records qualifying under high ·(b)(2)· are those containing or constituting rules, regulations, orders, manuals, directives, instructions, and unclassified portions of security classification guides, the release of which would allow circumvention of these rules, regulations, and policies, thereby substantially hindering the effective performance of the mission of the Department of Defense. Examples include: (i) Critical infrastructure information that reasonably could be expected to enable someone to succeed in causing the harms described in Homeland Security Presidential Directive 7. [2] This exempt information could include agency vulnerability assessments or evaluations of items of critical infrastructure that are internal to the Government. (ii) Those operating rules, guidelines, and manuals for DoD investigators, inspectors, auditors, or examiners that must be protected in order for the DoD Component to fulfill a legal requirement. (iii) Personnel and other administrative matters, such as examination questions and answers used in training courses or in the determination of the qualifications of candidates for employment, entrance on duty, advancement, or promotion. (iv) Computer software (Government-owned), the release of which would allow circumvention of a statute or of DoD rules, regulations, orders, manuals, directives, or instructions. In this situation, the use of the software must be closely examined to ensure a circumvention possibility exists. (2) Low ·(b)(2)·. Records qualifying under low ·(b)(2)· are those that are trivial and housekeeping in nature for which there is no legitimate public interest or benefit to be gained by release, and for which processing the request would constitute an administrative burden. Examples include rules for personnel use of parking facilities or regulation of lunch hours, statements of policy as to sick leave, and administrative data such as file numbers, mail routing stamps, initials, data processing notations, brief references to previous communications, and other like administrative markings. (c) Exemption 3. Pursuant to 5 U.S.C. 552(b)(3)

One questioned use of the CNSSI-4009 Glossary instead of the NIST Glossary of Terms. One comment requested a change to text quoted from another source. One commenter asserted that the rule includes no reference to ·existing FAR, DFARS, or DoD authoritative sources· and recommended that they be added in instead referencing NIST publications only. One comment asked if it is necessary to read and understand all FIPS, NIST SP 800, CNSSI, and ISO/IEC documents incorporated by referenced in §.170.2. One comment requested the references for CMMC Assessment Guides in Appendix A be changed to

NIST SP 800-171A Jun2018 and NIST SP 800-172A Mar2022. Two comments noted version numbers are not always provided for two specific document sources. Another comment requested references for supporting information, resources, and training for the DIB. A commenter asked if the term 'Government Information Systems' was equivalent to the term 'Federal Information Systems' while another expressed that the term, 'CMMC Level 2 Final Certification Assessment' was confusing given that 'Assessment' and 'Certification' are two separate and distinct terms. Another comment noted that the Summary Information section states there is a difference between a POA and a POA&M but recommended both terms be defined for clarity. One comment stated the 'CMMC Certified Assessor (CCA)' definition and acronym are not used consistently in the rule and the current CMMC AB's website. Another comment noted that the term, 'related practitioners' under the definition of CAICO in § 170.4 could be confused with the term 'Registered Practitioners (RP)' used by the CMMC AB as their designation for consultants. One comment stated that the DoD must be deliberate in its use of certain terms, especially the words 'must' and 'shall', which connote legal requirements, versus words like 'will', 'expected', 'can', 'may', 'should', etc., which are permissive (i.e., optional) One commenter noted the word 'practice' was replaced multiple times based on a comparison of pre-publication drafts with the formal drafts that were published for public comment. Another comment asserted that the DoD is falsely describing the CMMC program as addressing 'basic' cybersecurity requirements when this is the most demanding cybersecurity standard ever produced. One commenter objected to the CMMC Level 1, 2, and 3 Assessment definitions in § 170.4 referring to the content of corresponding rule sections and suggested that the definitions be deleted from § 170.4 unless they can be succinctly defined without doing so. Response: The rule has been updated to reference DoD Manual 8140 'Cyberspace Workforce Qualification and Management Program' which replaced DoD Manual 8570, 'Information Assurance Workforce Improvement Program'. DOD Manual 8140.03 is available at: <https://dodcio.defense.gov/Portals/0/Documents/Library/DoDM-8140-03.pdf> .

(x) 252.225-7050, Disclosure of Ownership or Control by the Government of a Country that is a State Sponsor of Terrorism. * * * * * PART 209-CONTRACTOR QUALIFICATIONS 3. Amend section 209.104-1, by revising paragraph (g)(i) to read as follows: 209.104-1 General standards. * * * * * (g)(i) Ownership or control by the government of a country that is a state sponsor of terrorism. (See 225.771.) * * * * * 4. Revise section 209.104-70 to read as follows: 209.104-70 Solicitation provision. Use the provision at 252.209-7002, Disclosure of Ownership or Control by a Foreign Government, in all solicitations, including those subject to the procedures in FAR part 13, when access to proscribed information is necessary for contract performance. If the solicitation includes the provision at FAR 52.204-7, do not separately list the provision 252.209-7002 in the solicitation. 5. Amend section 209.405, by revising paragraph (b)(i) to read as follows: 209.405 Effect of listing. * * * * * (b)(i) The Procurement Cause and Treatment Code 'H' annotation in the Exclusions section of the System for Award Management (SAM Exclusions) identifies contractor facilities where no part of a contract or subcontract may be performed because of a violation of the Clean Air Act (42 U.S.C. 7606) or the Clean Water Act (33 U.S.C. 1368). * * * * * 6. Revise section 209.405-2 to read as follows: 209.405-2 Restrictions on subcontracting. (a) The contracting officer shall not consent to any subcontract with a firm, or a subsidiary of a firm, that is identified by the Secretary of Defense in SAM Exclusions as being owned or controlled by the government of a country that is a state sponsor of terrorism unless the agency head states in writing the compelling reasons for the subcontract. (See also 225.771.) 7. Revise section 209.409 to read as follows: 209.409 Solicitation provision and contract clause. Use the clause at 252.209-7004, Subcontracting with Firms that are Owned or Controlled by the Government of a Country that is a State Sponsor of Terrorism, in solicitations and contracts with a value of \$150,000 or more. PART 212-ACQUISITION OF COMMERCIAL ITEMS 8. Amend section 212.301 by: a. Removing paragraph (f)(xi); b. Redesignating paragraphs (f)(xii) through (xlvi) as (xi) through (xlvii); and b. Adding a new paragraph (f)(xlviii) to read as follows: 212.301 Solicitation provisions and contract clauses for the acquisition of commercial items. (f) * * * * * (xlviii) Use the provision at 252.225-7050, Disclosure of Ownership or Control by the Government of a Country that is a State Sponsor of Terrorism, as prescribed in 225.771-5, to comply with 10 U.S.C. 2327(b) . * * * * * PART 225-FOREIGN ACQUISITION 225.701 [Amended] 9. In section 225.701, remove the section text. 10. Add sections 225.771, 225.771-0, 225.771-1, 225.771-2, 225.771-3, 225.771-4, and 225.771-5 to subpart 225.7 to read as follows: 225.771 Prohibition on contracting or subcontracting with a firm that is owned or controlled by the government of a country that is a state sponsor of terrorism. 225.771-0

requires federal contractors and subcontractors to implement 15 basic cyber hygiene requirements, as applicable, to protect contractor information systems that process, store, or transmit FCI. December 31, 2017, was DoD's deadline for contractors to implement, as applicable, the cybersecurity protection requirements set forth in NIST SP 800-171 Rev 2, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, in accordance with DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting. The current NIST 800-171A Assessment Guide states, "For the CUI security requirements in NIST Special Publication 800-171 Rev 2, nonfederal organizations describe in a system security plan, how the specified requirements are met or how organizations plan to meet the requirements [in a Plan of Action]." [53] NIST's process provides contractors with a tool to assess their security posture and decide if or when to mitigate the risks based upon the organizational risk tolerance. As such, a contractor could be compliant with NIST SP 800-171 Rev 2 if some of NIST SP 800-171 Rev 2 requirements are implemented but others are listed in a Plan of Action. As a result, at present, defense contractors and subcontractors can process, store, or transmit CUI without having implemented all security requirements set forth in NIST SP 800-171 Rev 2 and without establishing concrete, prompt, and enforceable timelines for addressing shortfalls and gaps documented in the Plan of Action. Findings from DoD Inspector General report (DODIG-2019-105 "Audit of Protection of DoD Controlled Unclassified Information on Contractor-Owned Networks and Systems") indicated that DoD contractors did not consistently implement mandated system security requirements for safeguarding CUI and recommended that DoD take steps to assess a contractor's ability to protect this information. CMMC adds a third-party assessment requirement, as applicable, to verify defense contractors and subcontractors have implemented the required security requirements prior to award. CMMC also adds affirmation processes at every CMMC level requiring contractors and subcontractors to attest to compliance with CMMC's security requirements and then provide annual affirmations thereafter. (b) Comprehensive Implementation of Cybersecurity Requirements Although the security requirements in NIST SP 800-171 Rev 2 address a range of threats, they do not sufficiently address Advanced Persistent Threats (APTs). An APT is an adversary that possesses sophisticated levels of expertise and significant resources, which allow it to create opportunities to achieve its objectives by using multiple attack vectors (e.g.,

-----| |
 [Murphy] | S. Murphy, 'RPKI Tutorial: Routing Security and RPKI', NANOG on the Road (NOTR), St. Louis, MO, November, 2015 <https://www.nanog.org/sites/default/files/04-Murphy-StLouis.pdf> | |
 [NABCO] | 'DDoS-DoS-attack-BCOP,' North American BCOP, <http://nabcop.org/index.php/DDoS-DoS-attack-BCOP> | | [Naik] | A. Naik, 'Internet Vulnerability Takes Down Google,' ThousandEyes report, November 2018 . <https://blog.thousandeyes.com/internet-vulnerability-takes-down-google/> | | [NANOG] | 'Practical BGP Origin Validation using RPKI: Vendor Support, Signing and Validation Services, and Operational Experience,' NANOG Track (multiple presentations) at NANOG 67, Chicago, IL, June 2016 . <https://archive.nanog.org/meetings/nanog67/agenda> | | [NANOG-list] | 'Intra-AS messaging for route leak prevention,' NANOG Email List - Discussion Thread, June 2016. <http://mailman.nanog.org/pipermail/nanog/2016-June/thread.html#86348> | | [NCCoE-sidr] | W. Haag, D. Montgomery, W.C. Barker, A. Tan, 'Protecting the Integrity of Internet Routing: Border Gateway Protocol (BGP) Route Origin Validation, Volume B,' NIST Special Publication (SP) 1800-14B, August 2018.

note 15, p. 3. Back to Citation 454. "Proposed 45 CFR 164.308(a)(1)(ii)(A) . Back to Citation 455. Id. Back to Citation 456. See, e.g., "New York State Register," supra note 14. Back to Citation 457. "Making a List and Checking it Twice: HIPAA and IT Asset Inventories," supra note 451. Back to Citation 458. Id. Back to Citation 459. "NIST defines the Internet of Things as "[t]he network of devices that contain the hardware, software, firmware, and actuators which allow the devices to connect, interact, and freely exchange data and information." NIST definition of "Internet of Things," Glossary, Computer Security Resource Center, National Institute of Standards and Technology, U.S. Department of Commerce, https://csrc.nist.gov/glossary/term/internet_of_things . Back to Citation 460. . See "Guidance on Risk Analysis," Office for Civil Rights, U.S. Department of Health and Human Services (July 22, 2019), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/guidance-risk-analysis/index.html?language=es> . Back to Citation 461. Id.; see also Jeffrey A. Marron, "Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide," NIST Special Publication 800-66, Revision 2, National Institute of Standards and Technology, U.S. Department of Commerce, p.28-84 (Feb. 2024),

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-66r2.pdf> . Back to Citation 462. · See ·Guidance on Risk Analysis,· supra note 460. Back to Citation 463. See id. Back to Citation 464. · See ·Security Risk Assessment Tool,· Office for Civil Rights and Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services (updated Sept. 5, 2023), <https://www.healthit.gov/topic/privacy-security-and-hipaa/security-risk-assessment-tool> . Back to Citation 465. · See ·HIPAA Security Rule,· National Institute of Standards and Technology, U.S. Department of Commerce (Jan. 3, 2011, updated July 21, 2022), <https://www.nist.gov/programs-projects/security-health-information-technology/hipaa-security-rule> . Back to Citation 466. · See ·HIPAA Security Rule Crosswalk to NIST Cybersecurity Framework,· Office for Civil Rights, U.S. Department of Health and Human Services (June 2020), <https://www.hhs.gov/guidance/sites/default/files/hhs-guidance-documents/nist-csf-to-hipaa-security-rule-crosswalk-02-22-2016-final.pdf> . Back to Citation 467. ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461. Back to Citation 468. See id. Back to Citation 469. ·This component of the assessment would be accomplished under the NPRM, if adopted, through compliance with the proposed standard for technology asset inventory at proposed 45 CFR 164.308(a)(1)(i) . Under the current Security Rule, we consider the technology asset inventory to be a component of the standard for risk analysis. Back to Citation

Other comments asked what tools would be available to assist contractors in checking subcontractor compliance with CMMC requirements or suggested that SPRS should be made available for this purpose. One suggested that without this transparency, CMMC compliance would become a meaningless effort to ·check the box· without actual steps to secure their systems. Another simply asked if they would have their own SPRS and eMASS access, or access through their prime. Some asked what action meets the rule's requirement to ·require subcontractor compliance·, i.e., does simply including the CMMC clause in subcontracts meet that requirement. One comment objected to the definition of subcontractor used in the rule, which they stated was overly broad and would result in application of CMMC requirements to too many businesses. Some comments suggested the flow-down requirement apply only to one sub-tier, while another requested advance notice of solicitations that plan to include CMMC requirements. One comment suggested that CUI be treated more like classified information, meaning to limit sharing of CUI with subcontractors. Some comments asked whether prime contractors are responsible for verifying subcontractor compliance with DFARS clause 252.204-7012, as C3PAOs do during an assessment. Two comments recommended rephrasing the flow-down section, with one specifically asking to clarify it is required only when FCI or CUI will be processed, stored, or transmitted in the performance of any particular prime contract. Another suggested edits for clarity or for consistency with DFARS clause 252.204-7012. Response: It is up to each OSA to protect FCI and CUI and to determine the assessment boundary, policies, and procedures necessary to do that. Section 170.23 specifically addresses the CMMC requirements that apply to subcontractors that will process, store, or transmit FCI or CUI. Section 170.23 addresses flow down of CMMC requirements from the prime contractor to the subcontractors in the supply chain. Prime contractors are responsible for complying with contract terms and conditions, including the requirement to flow down applicable CMMC requirements to subcontractors. The DoD modified §.170.23(a)(3) to clarify that when a subcontractor will process, store, or transmit CUI in performance of the subcontract and the Prime contractor has, for the associated prime contract, a requirement of Level 2 certification assessment, then CMMC Level 2 certification assessment is the minimum requirement for the subcontractor. Requirements for External Service Providers are defined in §.170.4; not all companies that provide services to an OSA are considered ESPs. (printed page 83117)

(I) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to that individual, and record amendment procedures for this record system. (J) For comparability with the exemption claimed from subsection (f), the civil remedies provisions of subsection (g) must be suspended for this record system. Because of the nature of criminal investigations, standards of accuracy, relevance, timeliness, and completeness cannot apply to this record system. Information gathered in an investigation is often fragmentary and leads relating to an individual in the context of one investigation may instead pertain to a second investigation. (2) System identifier and name.

CIG-06, Investigative Files. (i) Exemption. Any portion of this system which falls within the provisions of 5 U.S.C. 552a(j)(2) may be exempt from the following subsections of 5 U.S.C. 552a (c)(3), (c)(4), (d), (e)(1), (e)(2), (e)(3), (e)(4) (G), (H), (I), (e)(5), (e)(8), (f), and (g). (ii) Authority. 5 U.S.C. 552a(j)(2). (iii) Reasons. (A) From subsection (c)(3) because the release of accounting of disclosure would inform a subject that he or she is under investigation. This information would provide considerable advantage to the subject in providing him or her with knowledge concerning the nature of the investigation and the coordinated investigative efforts and techniques employed by the cooperating agencies. This would greatly impede OIG's criminal law enforcement. (B) From subsection (c)(4) and (d), because notification would alert a subject to the fact that an open investigation on that individual is taking place, and might weaken the on-going investigation, reveal investigatory techniques, and place confidential informants in jeopardy. (C) From subsection (e)(1) because the nature of the criminal and/or civil investigative function creates unique problems in prescribing a specific parameter in a particular case with respect to what information is relevant or necessary. Also, due to OIG's close liaison and working relationships with other Federal, state, local and foreign country law enforcement agencies, information may be received which may relate to a case under the investigative jurisdiction of another agency. The maintenance of this information may be necessary to provide leads for appropriate law enforcement purposes and to establish patterns of activity which may relate to the jurisdiction of other cooperating agencies.

Module 11 -Change Control and Management Module B. The Environment with MLS added. Impact of an MLS accreditation on configuration management Hardware, ancillary equipment, software, especially upgrading to new functionality. Maintaining accreditation -documentation for the Life cycle A checklist of warning signs for the Admin/Security staff Addressing security violations (vulnerabilities) in the MLS environment How to use the CERT to best advantage. Objectives of the course: Give managers and Technical personnel the tools to make cost-effective Operational decisions regarding MLS Information Systems. Course Curriculum consists of: The Technology with MLS added The Information Systems equivalents to Markings, Caveats, handling instructions -Mandatory Access Control labels Exploring operational impacts of MLS: MAC vs DACvulnerabilities New audit considerations - impact of MLS and MAC on the makeup and sensitivity of the Audit Trail data. Tracking an atomic action through several audit trails. Enhancing the security profile of an MLS system Impact of an MLS accreditation on Configuration Management A checklist of warning signs for the Admin/Security staff Addressing security violations How to use the CERT to best advantage Impact of having a CRYPTO in the closet. You will receive checklists and suggestions for operating sensitive systems daily.

PS.L2-3.9.1 · Screen Individuals CMMC Assessment Guide · Level 2 | Version 2.13 175 Personnel Security (PS) PS.L2-3.9.1 · SCREEN INDIVIDUALS Screen individuals prior to authorizing access to organizational systems containing CUI. ASSESSMENT OBJECTIVES [NIST SP 800-171A]157 Determine if: [a] individuals are screened prior to authorizing access to organizational systems containing CUI. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]157 Examine [SELECT FROM: Personnel security policy; procedures addressing personnel screening; records of screened personnel; system security plan; other relevant documents or records]. Interview [SELECT FROM: Personnel with personnel security responsibilities; personnel with information security responsibilities]. Test [SELECT FROM: Organizational processes for personnel screening]. DISCUSSION [NIST SP 800-171 REV. 2]158 Personnel security screening (vetting) activities involve the evaluation/assessment of individual-s conduct, integrity, judgment, loyalty, reliability, and stability (i.e., the trustworthiness of the individual) prior to authorizing access to organizational systems containing CUI. The screening activities reflect applicable federal laws, Executive Orders, directives, policies, regulations, and specific criteria established for the level of access required for assigned positions. FURTHER DISCUSSION Ensure all employees who need access to CUI undergo organization-defined screening before being granted access. Base the types of screening on the requirements for a given position and role. 157 NIST SP 800-171A, p. 45. 158 NIST SP 800-171 Rev. 2, p. 31.

Level 3 certification assessment requires the CMMC Status of Final Level 2 (C3PAO) and compliance with the security requirements set forth in §.170.18 to protect CUI. CMMC Level 3 adds additional security requirements to those required by existing acquisition regulations as specified in this rule. A Level 3 certification assessment of the applicable contractor information system(s) provided by the DCMA Defense Industrial Base Cybersecurity Assessment Center (DIBCAC) is required to

validate implementation of the DoD-defined selected security requirements set forth in NIST SP 800-172 Feb2021. A CMMC Status of Final Level 2 (C3PAO) is a prerequisite to schedule a DCMA DIBCAC Level 3 certification assessment. DCMA DIBCAC will upload the Level 3 certification assessment results into the CMMC instantiation of eMASS, which will feed the information into SPRS. OSCs will submit in SPRS an initial affirmation of compliance, and, if necessary, a POA&M closeout affirmation, and then annually following the Final CMMC Status Date, an affirmation of continued compliance as set forth in § 170.22. The Level 3 certification assessment cost burdens are included in this part with the exception of the requirement for the OSC to upload the affirmation in SPRS that is included in the 48 CFR part 204 CMMC Acquisition rule and an update to DFARS collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Additionally, the information collection reporting requirements for the CMMC instantiation of eMASS are included in a separate ICR for this part and cover only those requirements pertaining to the CMMC process. As described, the CMMC Program couples an affirmation of compliance with certification assessment requirements to verify OSA implementation of cybersecurity requirements, as applicable. The CMMC Program addresses DoD's need to protect FCI and CUI during the acquisition and sustainment of products and services from the DIB. This effort is instrumental in ensuring cybersecurity is the foundation of future DoD acquisitions. Policy Problems Addressed by the Revised CMMC Program Implementation of the CMMC Program is intended to solve the following policy problems: Lack of Verification of Contractor Compliance With Cybersecurity Requirements

. Any official who willfully maintains a system of records without meeting the publication requirements, as prescribed by 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R, is subject to possible criminal penalties and/or administrative sanctions. § 310.9 Privacy boards and office, composition and responsibilities. (a) The Defense Privacy Board .(1) Membership. The Board shall consist of the DA&M, OSD, who shall serve as the Chair; the Director of the DPO, DA&M, who shall serve as the Executive Secretary and as a member; the representatives designated by the Secretaries of the Military Departments; and the following officials or their designees: the Deputy Under Secretary of Defense for Program Integration (DUSD(PI)); the Assistant Secretary of Defense for Health Affairs; the Assistant Secretary of Defense for Networks and Information Integration (ASD) (NII)/Chief Information Officer (CIO); the Director, Executive Services and Communications Directorate, WHS; the GC, DoD; and the Director for Information Technology Management Directorate (ITMD), WHS. The designees also may be the principal POC for the DoD Component for privacy matters. (2) Responsibilities. (i) The Board shall have oversight responsibility for implementation of the DoD Privacy Program. It shall ensure the policies, practices, and procedures of that Program are premised on the requirements of 5 U.S.C. 552a and OMB Circular A-130, as well as other pertinent authority, and the Privacy Programs of the DoD Component are consistent with, and in furtherance of, the DoD Privacy Program. (ii) The Board shall serve as the primary DoD policy forum for matters involving the DoD Privacy Program, meeting as necessary, to address issues of common concern so as to ensure uniform and consistent policy shall be adopted and followed by the DoD Components. The Board shall issue advisory opinions as necessary on the DoD Privacy Program so as to promote uniform and consistent application of 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R. (iii) Perform such other duties as determined by the Chair or the Board. (b) The Defense Data Integrity Board .(1) Membership. The Board shall consist of the DA&M, OSD, who shall serve as the Chair; the Director of the DPO, DA&M, who shall serve as the Executive Secretary; and the following officials or their designees: the representatives designated by the Secretaries of the Military Departments; the DUSD(PI); the (ASD) (NII)/CIO; the GC, DoD; the Inspector General, DoD; the ITMD, WHS; and the Director, Defense Manpower Data Center. The designees also may be the principal points of contact for the DoD Component for privacy matters. (2) Responsibilities. (i) The Board shall oversee and coordinate, consistent with the requirements of 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R, all computer matching programs involving personal records contained in system of records maintained by the DoD Components.

(iii) Reporting any change to the information provided on its SF 328 by resubmitting the SF 328 to DCSA within 15 business days of the change being effective. A disqualifying eligibility determination, based on the results of the change, will result in the C3PAO losing its authorization or accreditation. (6) Obtain a CMMC Level 2 Certification Assessment in accordance with the procedures specified in § 170.17(a)(1) and (c). This assessment, conducted by DCMA DIBCAC, shall meet all requirements for a Level 2 Final Certification Assessment and will not result in a CMMC Level 2 certificate. The CMMC Level 2 assessment process must be performed on a triennial basis.

(7) Provide all documentation and records in English. (8) Submit pre-assessment and planning material, final assessment reports, and CMMC certificates of assessment into the CMMC instantiation of eMASS. (9) Submit all assessment appeal investigations and decisions to include assessment results into the CMMC instantiation of eMASS. (10) Unless disposition is otherwise authorized by the CMMC PMO, maintain all assessment related records for a period of six (6) years. Such records include any materials provided by OSC, generated by the C3PAO in the course of an assessment, any working papers generated from Level 2 Certification Assessments; and materials relating to monitoring, education, training, technical knowledge, skills, experience, and authorization of all personnel involved in inspection activities; contractual agreements with OSCs; and organizations for whom consulting services were provided. (11) Provide any requested audit information, including any out-of-cycle from ISO/IEC 17020:2012 requirements, or subsequent revisions, to the Accreditation Body. (12) Ensure that all personal information is encrypted and protected in all C3PAO information systems and databases. (13) Meet the requirements for Assessment Team composition, comprised of a Lead CCA, CCAs, and any participating CCPs. (printed page 89126) (14) Implement a quality assurance function that ensures the accuracy and completeness of assessment data prior to upload into the CMMC instantiation of eMASS. Any individual fulfilling the quality assurance function must be a CCA and cannot be a member of an Assessment Team for which they are performing a quality assurance role. A quality assurance individual shall manage the C3PAO's quality assurance reviews as defined in paragraph (b)(15) of this section and the appeals process as required by paragraph (b)(21) of this section and in accordance with ISO/IEC 17020:2012 and ISO/IEC 17011:2017, or subsequent revisions. (15) Conduct quality assurance reviews for each assessment, including observations of the Assessment Team's conduct and management of CMMC assessment processes. (16) Ensure that all CMMC assessment activities are performed on the information system within the CMMC Assessment Scope.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 G overnment Accountability Office
2758 HVA High Value Asset IoT Internet of Things ISAC Information Sharing and Analysis Centers
ISAO Information Sharing and Analysis Organizations ISOO Information Security Oversight Office
IT Information Technology ITL Information Technology Laboratory NARA National Archives and
Records Administration NIST National Institute of Standards and Technology NIST I R NIST
Interagency or Internal Report ODP Organization-D efined Parameter OMB Office of Management and
Budget OT Operational Technology PII Personal Identification Information PLC Programmable
Logic Controller PRA Penetration-R esistant Architecture ROI Retur

zed disclosure of information, unauthorized modification of information, unauthorized destruction of
information, or loss of information or information system availability. | | Impact Value [CNSSI No.
1253] | The assessed potential impact resulting from a compromise of the confidentiality, integrity,
or availability of an information type, expressed as a value of low, moderate, or high. | |
Industrial Control System [NIST SP 800-39] | An information system used to control industrial
processes such as manufacturing, product handling, production, and distribution. Industrial control
systems include supervisory control and data acquisition systems used to control geographically
dispersed assets, as well as distributed control systems and smaller control systems using
programmable logic controllers to control localized processes. | | Information [CNSSI No. 4009] |
Any communication or representation of knowledge such as facts, data, or opinions in any medium or
form, including textual, numerical, graphic, cartographic, narrative, or audiovisual. | | [FIPS 199]
| An instance of an information type. | | Information Owner [CNSSI No. 4009] | Official with
statutory or operational authority for specified information and responsibility for establishing the
controls for its generation, classification, collection, processing, dissemination, and disposal.
See Information Steward . | | Information Resources [44 U.S.C., Sec. 3502] | Information and related
resources, such as personnel, equipment, funds, and information technology. |

This includes approved CUI categories and category descriptions, the basis for safeguarding and
dissemination controls, and procedures for the use of CUI. 2 Procedures for the use of CUI include
marking, safeguarding, transporting, disseminating, reusing, and disposing of the information. The
CUI federal regulation provides guidance to federal agencies on the designation, safeguarding,
marking, dissemination, decontrolling, and disposition of CUI; establishes self-inspection and
oversight requirements; and delineates other facets of the program. [5] The CUI regulation
requires federal agencies that use federal information systems 3 A federal information system is a
system that is used or operated by an executive agency, by a contractor of an executive agency, or

by another organization on behalf of an executive agency. Any system that does not meet the definition of a federal information system is designated as a nonfederal system. to process, store, or transmit CUI to comply with NIST standards and guidelines. The responsibility of federal agencies to protect CUI does not change when such information is shared with nonfederal organizations.

By implementing this standard, the risk of inappropriate disclosure, alteration, or destruction of ePHI is minimized. A regulated entity must determine those persons and technology assets that need access to ePHI within its environment. The implementation specifications associated with the standard on information access management are closely related to those associated with the standard for workforce security. [567] Compliance with the proposed and existing standards for information access management should support a regulated entity's compliance with the Privacy Rule's minimum necessary requirements, which requires a regulated entity to evaluate its practices and enhance safeguards as needed to limit unnecessary or inappropriate access to and disclosure of PHI. [568] OCR's enforcement experience demonstrates that many regulated entities have not adequately implemented this standard. Thus, we believe it is necessary to consider strengthening the requirement. For example, on one occasion, a large covered entity's failure to implement its written policies and procedures to ensure that employees only had access to ePHI that they had proper authorization or authority to access enabled an employee to access the ePHI of more than 24,000 individuals. [569] This failure also enabled other employees to inappropriately access the ePHI of a celebrity. [570] To ensure that regulated entities implement recommendations and best practices for securing ePHI, we propose to require in the standard for information access management and associated implementation specifications that a regulated entity must establish and implement written policies and procedures for authorizing access to ePHI and relevant electronic information systems that are consistent with the Privacy Rule. The Department also proposes to redesignate the standard at 45 CFR 164.308(a)(4)(i) as proposed 45 CFR 164.308(a)(10)(i) and to add a paragraph heading to clarify the organization of the regulatory text. Additionally, the Department proposes to modify three of the associated existing implementation specifications and to add three new implementation specifications as follows. Specifically, the Department proposes to redesignate the implementation specification for isolating health care clearinghouse functions as proposed 45 CFR 164.308(a)(10)(ii)(A) and to modify it to require a health care clearinghouse that is part of a larger organization to establish and implement written policies and procedures that protect the ePHI and relevant electronic information systems of the clearinghouse from unauthorized access by the larger organization.

3.3.3 KMS Requirements Table 4-1 KMS Requirements Attribute Low Moder High Requirements Reference Key material and cryptographic operations protection ate X X X Software protection of cryptographic materials used in individual devices (e.

lementation, but there are challenges both with the complexity of creating complete, accurate SBOMs and with trust that either the SBOM or the device has not been altered so that they no longer match. Participants largely seemed to agree that many manufacturers currently have poor visibility into and management control over the supply chains for their products.

The CMMC Program is designed to enforce protection of unclassified information, to include FCI and CUI, not intended for public release that is shared by the Department with its contractors and subcontractors. The program provides the Department increased assurance that contractors and subcontractors are meeting the cybersecurity requirements that apply to acquisition programs and systems that process federal contract information and controlled unclassified information. (printed page 89075) Any discussion regarding the use of classified networks is outside of the scope of the CMMC Program. 20. CMMC Requirements Comment: There were multiple comments suggesting additions, deletions, or changes to model requirements. One commenter noted multiple instances of CMMC requirements with the term `information system' rather than `system' used in NIST SP 800-171 Rev 2, asking if CMMC meant to change the intent by inserting `information' in these requirements. Multiple commenters questioned the intent, clarity, or interpretation of several CMMC requirements/NIST SP 800-171 Rev 2 requirements, recommending clarification regarding vulnerability management, protection of mobile devices, review of audit logs, disabling of identifiers, FIPS validated encryption, and malicious code scans. One comment suggested that CMMC 1.0 requirements RM.2.141 and RM.3.144 are redundant and recommended incorporating RM 3.146 into CA.2.159, justifying that a plan of action is essentially a risk management plan. Two commenters noted that two CMMC 1.0

requirements (RE.2.137 and RE.3.139) are unclear as they do not specify what data requires backup, or the meaning of resilient backup. One commenter said that CMMC 1.0 requirement MA.2.114 removed the qualifier of 'maintenance' when describing personnel requiring supervision of maintenance activities, asking if this is an insignificant change to the NIST SP 800-171 Rev 2 security requirement, or whether there is some rationale or message that the CMMC specification is trying to adjust by deviating from the NIST SP 800-171 Rev 2. Two commenters stated that CMMC 1.0 requirement MP.1.1.18 requires only FCI be sanitized, but, for CMMC 1.0 Level 3 (CMMC Level 2 under CMMC 2.0) assessments, there is no requirement to sanitize CUI. One commenter wanted to know which CMMC requirement requires a medium assurance certificate for reporting cyber incidents. Response:

Establish and implement written policies and procedures to limit physical access to all of its relevant electronic information systems and the facility or facilities in which they are housed, while ensuring that properly authorized access is allowed. (2) Implementation specifications (i) Contingency operations. Establish (and implement as needed) written procedures that allow facility access in support of the covered entity's or business associate's contingency plan required by § 164.308(a)(13). (ii) Facility security plan. Establish and implement written policies and procedures to safeguard all facilities and the equipment therein from unauthorized physical access, tampering, and theft. (iii) Access management and validation procedures. Establish and implement written procedures to authorize and manage a person's access to facilities based on their role or function, including visitor management. (iv) Physical maintenance records. Establish and implement written policies and procedures to document repairs and modifications to the physical components of a facility that are related to security, including but not limited to hardware, walls, doors, locks, and security cameras. (v) Maintenance. For each facility, review and test the written policies and procedures required by this paragraph (a)(2) at least once every 12 months, and modify such policies and procedures as reasonable and appropriate. (b) Standard: Workstation use (1) General. Establish and implement written policies and procedures that govern the use of workstations that access electronic protected health information or the covered entity's or business associate's relevant electronic information systems. (2) Implementation specifications (i) Policies and procedures. The written policies and procedures must specify all of the following with respect to a workstation that accesses electronic protected health information or the covered entity's or business associate's relevant electronic information systems: (A) The functions for which a workstation may be used. (B) The manner in which a workstation may be used to perform those functions. (C) The physical attributes of the surroundings of a specific workstation or class of workstation that can access electronic protected health information, including the removal of such workstations from a facility and the movement of such workstations within and outside of a facility. (ii) Maintenance. Review and test written policies and procedures at least once every 12 months, and modify as reasonable and appropriate. (c) Standard: Workstation security. Implement and modify physical safeguards for all workstations that access electronic protected health information or relevant electronic information systems, to address the written policies and procedures for workstation use required by paragraph (b) of this section and restrict access to authorized users. (d) Standard: Technology asset controls (1) General.

computer cybersecurity; control; digital twin technology; instrumentation; real-time command; real-time monitoring; simulation; standards; testing; trust; use case scenarios. 7. Instrumentation and monitoring: Instrumentation of a digital twin is a beneficial and unique advantage that digital twin technology offers. While one might not be able to instrument the physical object, one may be able to instrument the digital twin. However, instrumentation and probes are not as simple or easy to correctly inject into a digital twin as might be expected. Much can be learned here from the safety-critical software community. First, a determination of where to inject the probes is necessary [28], though this is not easy and can be more art than science. Second, the number of probes to inject is also a consideration. As shown in real-time systems, probes can slow down performance and timing, which may cause a problem for synchronization between the digital twin and physical object. That said, there are ways to reduce this impact by having the probes only collect raw data rather than compute internal test results, such as built-in self-tests. Collecting the 'right' information from the internal state of an executing digital twin is an expensive and error-prone effort. 8. Heterogeneity of standards: Heterogeneity of different formats for digital twins may cause composability problems [29]. Composing digital twin definitions from different component vendors may not be achievable if vendors misuse standardized formats [4]. This is a consideration for trusting composed digital twins. 9. Non-functional requirements: Functional requirements state what a system shall do, negative requirements state what a system shall not do, and non-functional requirements

(i.e., the 'ilities' 7) typically state what level of quality the system shall exhibit for both the functional and negative requirements. The 'ilities' apply to both 'things' and the systems into which they are built.

Recent security-related incidents indicate the need for a secure software supply chain to protect software products (also referred to as code) during the development, build, distribution, and maintenance phases. Of particular concern is provisioning and updating software that plays a critical role in platform security. A wide range of software products, including firmware, operating systems, mobile applications, and application container images must be distributed and updated in a secure and automatic way to prevent forgery and tampering. This white paper targets software developers and product vendors who are implementing a code signing system or reviewing the security of an existing system, with the goal of achieving improved security and customer confidence in code authenticity and integrity. System integrators and administrators who are concerned about the trustworthiness of the applications that are installed and run on their systems will learn the properties they should expect from a code signing solution to protect their software supply chain. This white paper describes features and architectural relationships of typical code signing solutions that are widely deployed today. It defines code signing use cases and identifies some security problems that can arise when applying code signing solutions to those use cases. Finally, it provides recommendations for avoiding those problems, and resources for more information. Properly applied, these recommendations will help to ensure that the software supply chain is resistant to attack.

<https://www.federalregister.gov/documents/2020/09/29/2020-21123/defense-federal-acquisition-regulation-supplement-assessing-contractor-implementation-of> . Back to Citation 11.

<https://www.acq.osd.mil/asda/dpc/cp/cyber/docs/safeguarding/NIST-SP-800-171-Assessment-Methodology-Version-1.2.1-6.24.2020.pdf> Back to Citation 12. Information on the Department's agenda for all rulemakings can be found at <https://www.reginfo.gov/public/do/eAgendaMain> and then selecting the relevant agency and rule name. Back to Citation 13.

<https://www.iso.org/standard/67198.html> . Back to Citation 14.

<https://www.iso.org/committee/54998.html> . Back to Citation 15.

<https://www.iso.org/standard/52993.html> . Back to Citation 16. This system is accessible only to authorized users. Back to Citation 17.

<https://irp.fas.org/offdocs/nsdd/nsdd-189.htm> . Back to Citation 18.

<https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/DoDI/858201p.pdf?ver=2019-12-09-143118-860> . Back to Citation 19. Based on information from the Council of Economic Advisors report: The Cost of Malicious Cyber Activity to the U.S. Economy, 2018. Back to Citation 20.

Based on information from the Center for Strategic and International Studies report on the Economic Impact of Cybercrime; <https://www.csis.org/analysis/economic-impact-cybercrime> . Back to Citation 21.

Based on information from the Federal Procurement Data System, the average number of unique prime contractors is approximately 212,650 and the number of known unique subcontractors is approximately 8,300. (FPDS from FY18-FY21). Back to Citation 22.

<https://www.govinfo.gov/content/pkg/PLAW-116publ92/pdf/PLAW-116publ92.pdf> . Back to Citation 23.

<https://www.gao.gov/assets/gao-22-104746.pdf> . Back to Citation 24.

<https://www.ic3.gov/Media/News/2021/210310.pdf> . Back to Citation 25.

<https://www.cisa.gov/uscert/ncas/current-activity/2021/07/04/cisa-fbi-guidance-msps-and-their-customers-affected-kaseya-vsa> . Back to Citation 26.

<https://www.mitre.org/sites/default/files/publications/pr-18-2417-deliver-uncompromised-MITRE-study-26AUG2019.pdf> . Back to Citation 27.

<https://www.cisa.gov/uscert/ncas/alerts/aa22-057a> . Back to Citation 28.

DODIG-2019-105 Audit of Protection of DoD CUI on Contractor-Owned Networks and Systems Back to Citation 29.

The number of unique awardees impacted each year is 1/3 of the average number of annual awardees according to the Electronic Data Access system (31,338/3 = 10,446). This estimate does not address new entrants or awardees who discontinue doing business with DoD. Back to Citation 30.

Includes all businesses with the exception of those defined under the small business criteria and size standards provided in 13 CFR 121.201 (See FAR Part 19.102) Back to Citation

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook

for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204 and 252 [Docket DARS-2019-0049] RIN 0750-AK14 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to modify the text of an existing DFARS clause to clarify its intent and conform its language to current DFARS terminology, pursuant to action taken by the Regulatory Reform Task Force. DATES: Effective April 8, 2020. FOR FURTHER INFORMATION CONTACT: Ms. Carrie Moore, telephone 571-372-6093. SUPPLEMENTARY INFORMATION: I. Background DoD published a proposed rule in the Federal Register at 84 FR 58362 on October 31, 2019, to modify DFARS clause 252.207-7002, Payment for Subline Items Not Separately Priced, to conform the text of the clause to the current contract line item structure terminology by replacing ·contract line item· with ·contract line or subline item· and add a prescription for the DFARS clause in the applicable section of DFARS 204.71. No public comments were received in response to the proposed rule. No changes are made in the final rule from the proposed rule. II. Applicability to Contracts at or Below the Simplified Acquisition Threshold and for Commercial Items, Including Commercially Available Off-the-Shelf Items This rule does not create any new provisions or clauses. The rule updates language used in the clause text to conform with current contract line item structure terminology. This rule does not change the applicability of the affected clause. III. Executive Orders 12866 and 13563 E.O.s 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866 , Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804 . IV. Executive Order 13771 This rule is not subject to E.O. 13771 , because this rule is not a significant regulatory action under E.O. 12866 . V. Regulatory Flexibility Act

ABE provides confidentiality and data integrity when used in a public environment with a large scope (e.g., cloud) of users. However, relying only on user-specified attributes may create various security issues from the perspectives of key management processes and intentional threats or attacks. Integrity: If an ABE system is outsourced, it requires trust so that the decrypted ciphertext is a legitimate message based on legitimate user attributes. Additionally, the message uploaded to the resource provider can be falsified, and it is unknown whether the value calculated by the Researchers are currently working on blockchain fundamentals and customizing blockchainbased ABE models for IoT applications to provide privacy and minimize computational overhead. For example, [QYLPYH] describes the use of a lightweight blockchain ABE to outsource decryption based on the blockchain, which can be extended to effectively reduce the burden of encryption computation on the user side. Blockchain technology can also provide integrity (i.e., the secret key does not contain specific information about users who may share their secret keys with other users) and the non-repudiation of data, as well as prevent the leaking of sensitive information from the ABE access structure [WZZGZZ].

(Comment 32) One comment requests clarification on how imported food samples that do not enter commerce will be handled based on the regulations. These food samples have the intended end use of analysis, experimentation, and/or subsequent destruction within approved company premises. The samples may be carried into the United States as personal baggage of company representatives or sent unaccompanied. The comment points out that food carried in personal baggage is exempt from the registration interim final rule only if the food is for personal enjoyment/use. Another foreign comment states that the recordkeeping requirement should not apply to commercial samples. The comment states that new exporters cannot be expected to engage in recordkeeping requirements concerning exports before testing marketing opportunities. (Response) Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States that is intended for consumption by humans or animals are subject to these regulations. The recordkeeping requirements would not apply to food samples that are used for quality assurance, research or analysis purposes, as long as the food samples are not consumed by humans or animals. Samples of food are considered to be for quality assurance, research or analysis purposes, rather than human consumption, when they are in small quantities (i.e., quantities consistent with the quality assurance, research, or analysis purposes) and the entire sample is used up by the analysis, destroyed after analysis, or destroyed following a reasonable retention period after analysis. The

analysis may include sensory examination, such as organoleptic examination for determining tea quality or detecting the presence of histamines. Evidence that an article of food is for quality assurance, research, or analysis purposes only might include, among other evidence, markings on the food and shipping documents. Food samples intended for consumption via test marketing, such as tasting at trade shows or product promotional tasting events, are subject to this subpart.

References: [SP 800-39] (Organization, Mission/Business Process, and System Levels); [SP 800-64]; [SP 800-160 v1] (System Requirements Definition, Architecture Definition, and Design Definition Processes); [NIST CSF] (Core [Identify Function]; Profiles); [OMB FEA]. NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

CHAPTER THREE PAGE 54 This publication is available free of charge from:

<https://doi.org/10.6028/NIST.SP.800-37r2> DOCUMENTATION OF PLANNED CONTROL IMPLEMENTATIONS TASK

S-4 Document the controls for the system and environment of operation in security and privacy plans. Potential Inputs: Security categorization; organization- and system-level risk assessment results (security, privacy, and/or supply chain); system element information; system component inventory; business impact or criticality analysis; list of security and privacy requirements allocated to the system, system elements, and environment of operation; risk management strategy; list of selected controls for the system and environment of operation; organizational security, privacy, and SCRM policies. Expected Outputs: Security and privacy plans for the system. Primary Responsibility: System Owner; Common Control Provider. Supporting Roles: Authorizing Official or Authorizing Official Designated Representative; Information Owner or Steward; Systems Security Engineer; Privacy Engineer; System Security Officer; System Privacy Officer. System Development Life Cycle Phase: New · Development/Acquisition. Existing · Operations/Maintenance. Discussion: Security and privacy plans contain an overview of the security and privacy requirements for the system and the controls selected to satisfy the requirements. The plans describe the intended application of each selected control in the context of the system with a sufficient level of detail to correctly implement the control and to subsequently assess the effectiveness of the control. The control documentation describes how system-specific and hybrid controls are implemented and the plans and expectations regarding the functionality of the system. The description includes planned inputs, expected behavior, and expected outputs where appropriate, typically for those controls implemented in the hardware, software, or firmware components of the system. Common controls are also identified in the plans. There is no requirement to provide implementation details for inherited common controls. Rather, those details are provided in the plans for common control providers and are made available to system owners. For hybrid controls, the organization specifies in the system-level plans the parts of the control that are provided by the common control provider and the parts of the control that are implemented at the system level. Organizations may develop a consolidated plan that incorporates security and privacy plans or maintain separate plans. If developing a consolidated plan, privacy programs collaborate with security programs to ensure that the plan reflects the selection of controls that provide protections with respect to managing the confidentiality, integrity, and availability of PII; and delineates roles and responsibilities for control implementation, assessment, and monitoring. For separate system security plans and privacy plans, organizations cross-reference the controls in all plans to help maintain accountability and awareness. The senior agency official for privacy reviews and approves the privacy plan (or integrated plan) before the plan is provided to the authorizing official or designated representative for review (see Task S-6). Organizations may document the control selection and tailoring information in documents equivalent to security and privacy plans, for example, in systems engineering or system life cycle artifacts or documents. Documentation of planned control implementations allows for traceability of decisions prior to and after the deployment of the system. To the extent possible, organizations reference existing documentation (either by vendors or other organizations that have employed the same or similar systems or system elements), use automated support tools, and coordinate across the organization to reduce redundancy and increase the efficiency and cost-effectiveness of control documentation. The documentation also addresses platform dependencies and includes any additional information necessary to describe how the capability required is to be achieved at the level of detail sufficient to support control implementation and assessment. Documentation for control implementations follows best practices for hardware and software development and for systems security and privacy engineering disciplines and is also consistent with established policies and procedures for documenting activities in the SDLC. In certain situations,

General Security of Information Agreements and General Security of Military Information Agreements) are negotiated with various foreign governments. Confidentiality requested by some foreign governments prevents a listing of the countries that have executed these agreements. The bilateral security agreement, negotiated through diplomatic channels: (A) Requires that each government provide substantially the same degree of protection to classified information released by the other government. (B) Contains provisions concerning limits on the use of each government's information, including restrictions on third-party transfers and proprietary rights. (C) Does not commit governments to share classified information, nor does it constitute authority to release classified material to that government. (D) Satisfies, in part, the eligibility requirements of the Arms Export Control Act concerning the agreement of the recipient foreign government to protect U.S. classified defense articles and classified information. (ii) The applicable CSA will provide a mechanism for contractors to access, for official purposes, classified general security agreements. (iii) Industrial security agreements have been negotiated with certain foreign governments that identify the procedures to be used when foreign government classified information is provided to U.S. industry and UUSG classified information is provided to foreign defense industry. (3) Authorization for disclosure. The GCA will provide disclosure guidance. (i) Contractors will only disclose non-public USG information to foreign persons in accordance with specified requirements of the contract. In the absence of any specified requirements the contractor will not disclose non-public USG information to foreign persons. (ii) Disclosure authorization may be in the form of an export license or other export authorization by a cognizant export authority. (iii) The contractor may not use disclosure guidance provided by the GCA for a previous contract or program unless so instructed in writing by the GCA or the licensing authority. (iv) Disclosure and export of classified information, authorized by an appropriate USG disclosure official, by a contractor will ensure the following: (printed page 83349) (A) International agreements. Contractors may not disclose classified information until agreements are signed by the participating government and disclosure guidance and security arrangements are established. The export of technical data pursuant to such agreements may be exempt by approval of the Department of State or the Department of Commerce. (B) Symposia, seminars, exhibitions, and conferences. Contractors must assure that any foreign nationals who will be attending a classified gathering have the appropriate export license, disclosure authority, and security assurance on file. (C) Visits by foreign nationals to the contractor.

(c) Include Privacy Act training in other courses of training when appropriate. Stress individual responsibilities and advise individuals of their rights and responsibilities under this part to ensure that it is understood that, where personally identifiable information is involved, individuals should handle and treat the information as if it was their information. §-310.38 Training methodology and procedures. (a) Each DoD Component is responsible for the development of training procedures and methodology. (b) The DPO shall assist the Components in developing these training programs and may develop privacy training programs for use by all DoD Components. (c) Components shall conduct training as frequently as believed necessary so that personnel who are responsible for or are in receipt of information protected by 5 U.S.C. 552a are sensitive to the requirements of this part, especially the access, use, and dissemination restrictions. Components shall give consideration to whether annual training and/or annual certification should be mandated for all or specified personnel whose duties and responsibilities require daily interaction with personally identifiable information. (d) Components shall conduct training that reaches the widest possible audience. Web-based training and video conferencing have been effective means to provide such training. §-310.39 Funding for training. Each DoD Component shall fund its own privacy training program. Subpart I-Reports §-310.40 Requirement for reports. The DPO shall establish requirements for DoD Privacy Reports and the DoD Components may be required to provide data. §-310.41 Suspense for submission of reports. The suspenses for submission of all reports shall be established by the DPO. §-310.42 Reports control symbol. Any report established by this subpart in support of the Privacy Program shall be assigned Report Control Symbol DD-COMP(A)1379. Subpart J-Inspections §-310.43 Privacy Act inspections. During internal inspections, Component inspectors shall be alert for compliance with this part and for managerial, administrative, and operational problems associated with the implementation of the Defense Privacy Program. Programs shall be reviewed as frequently as considered necessary by Components or the Component Inspector General. §-310.44 Inspection reporting. (a) Document the findings of the inspectors in official reports that are furnished the responsible Component officials. These reports, when appropriate, shall reflect overall assets of the Component Privacy Program inspected, or portion thereof, identify

deficiencies, irregularities, and significant problems. Also document remedial actions taken to correct problems identified. (b) Retain inspections reports and later follow-up reports in accordance with established records disposition standards. These reports shall be made available to the Privacy Program officials concerned upon request. Subpart K-Privacy Act Violations §-310.45 Administrative remedies.

It is estimated that the costs to perform an initial and annual affirmation of compliance with CMMC Level 1 for an other than small entity is \$584 A director (MGMT5) for 2 hours ($\$190.52/\text{hr} \times 2\text{hrs} = \381) A staff IT specialist (IT4) for 2.08 hours ($\$97.49/\text{hrs} \times 2.08\text{hrs} = \203) The Level 1 Self-Assessment and Affirmations cost burden will be addressed as part of the 48 CFR acquisition rule. Summary: The following is the annual other than small entities total cost summary for CMMC Level 1 self- (printed page 89090) assessments and affirmations over a ten-year period: (Example calculation, Year 1: $\$4,042$ per entity $\times 246$ entities (cumulative) = $\$994,233$). Small Entities Nonrecurring and recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with CMMC Level 1 since it is assumed the contractor or subcontractor has implemented the applicable security requirements. [39] Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 1 assessment and affirmation is $\$5,977$ (as summarized in 4.1.2, Table 2). A Level I Self-Assessment is conducted annually, and is based on the assumptions detailed: Phase 1: Planning and preparing for the assessment: $\$1,803$ A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) An external service provider (ESP) for 4 hours ($\$260.28 \times 4\text{hrs} = \$1,041$) Phase 2: Conducting the self-assessment: $\$2,705$ A director (MGMT5) for 6 hours ($\$190.52/\text{hr} \times 6\text{hrs} = \$1,143$) An external service provider (ESP) for 6 hours ($\$260.28 \times 6\text{hrs} = \$1,562$) Phase 3: Reporting of assessment results into SPRS: $\$909$ A director (MGMT5) for 2 hours ($\$190.52/\text{hr} \times 2\text{hrs} = \381) An external service provider (ESP) for 2 hours ($\$260.28/\text{hr} \times 2\text{hrs} = \521) A staff IT specialist (IT4-SB) for 0.08 hours [40] ($\$86.24/\text{hr} \times 0.08\text{hrs} = \7) Affirmation: initial affirmation post assessment: $\$560$ Reaffirmations: It is estimated that the costs to reaffirm a CMMC Level I annually for a small entity is $\$560$ A director (MGMT5) for 2 hours ($\$190.52/\text{hr} \times 2\text{hrs} = \381) A staff IT specialist (IT4-SB) for 2.08 hours ($\$86.24/\text{hr} \times 2.08\text{hrs} = \179) The Level 1 Self-Assessment and Affirmations cost burden will be addressed as part of the 48 CFR acquisition rule. Summary: The following is the annual small entities total cost summary for CMMC Level 1 self-assessments and affirmations over a ten-year period: (Example calculation, Year 1: $\$5,977$ per entity $\times 699$ entities (cumulative) = $\$4,177,845$). (printed page 89091) All Entities Summary The following is a summary of the combined costs for both small and other than small entities for CMMC Level 1 Self-Assessments and Affirmations over a ten-year period: CMMC Level 2 Self-Assessment and Affirmation Costs Other Than Small Entities Nonrecurring and Recurring Engineering Costs: There are no nonrecurring or recurring engineering costs associated with CMMC Level 2 Self-Assessment since it is assumed the contractor or subcontractor has implemented the NIST SP 800-171 Rev 2 security requirements.

evice connects to a Wi-Fi network, it will save the randomized MAC address into a network profile. Subsequent associations to the same Wi-Fi network will utilize the saved network profile information. It is important to recognize if the feature is enabled and which MAC address is the device's permanent and randomized address. Alternative enrollment methods may be required if MAC address based network access controls and/or MDM inventory tracking are used.

(G) From subsection (g) for compatibility with the exemption claimed from subsection (f), the civil remedies provisions of subsection (g) must be suspended for this record system. Because of the nature of criminal, administrative and civil investigations, standards of accuracy, relevance, timeliness and completeness cannot apply to open or closed investigations in this record system. Information gathered in criminal investigations is often fragmentary and leads relating to an individual in the context of one investigation may instead pertain to a second investigation. (25) System identifier and name. DPFPA 07, Counterintelligence Management Information System (CIMIS). (i) Exemption. Portions of this system that fall within 5 U.S.C. 552a (k)(2) are exempt from the following provisions of 5 U.S.C. 552a , section (c)(3); (d); (e)(1); (e)(4)(G) through (I); and (f) of the Act, as applicable. (printed page 14810) (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. (A) From subsections (c)(3) because making available to a record subject the accounting of disclosure from records concerning him or her would specifically reveal any investigative interest in the individual. Revealing this information could reasonably be expected to compromise ongoing efforts to investigate a known or suspected offender by notifying the record subject that he or she is under investigation. This information could also permit the record subject

to take measures to impede the investigation, e.g. destroy evidence, intimidate potential witnesses, or flee the area to avoid or impede the investigation. (B) From subsection (d) because these provisions concern individual access to and amendment of certain records contained in this system, including counterintelligence, law enforcement, and investigatory records. Compliance with these provisions could alert the subject of an investigation of the fact and nature of the investigation, and/or the investigative interest of agencies; compromise sensitive information related to national security; interfere with the overall counterintelligence and investigative process by leading to the destruction of evidence, improper influencing of witnesses, fabrication of testimony, and/or flight of the subject; could identify a confidential source or disclose information which would constitute an unwarranted invasion of another's personal privacy; reveal a sensitive investigation or constitute a potential danger to the health or safety of law enforcement personnel, confidential informants, and witnesses. Amendment of these records would interfere with ongoing counterintelligence investigations and analysis activities and impose an excessive administrative burden by requiring investigations, analyses, and reports to be continuously reinvestigated and revised.

One commentor correctly interpreted § 170.23(a)(3) as meaning that CMMC level 2 Certification requirements (not self-assessments) flow down for subcontractors that will handle CUI when the Prime contract specifies a CMMC Level 2 Certification requirement. At the time of award, the DoD may have no visibility into whether the awardee will choose to further disseminate DoD's CUI, but DFARS clause 252.204-7012 and DFARS clause 252.204-7021 require that the prime contractor flow down the information security requirement to any subcontractor with which the CUI will be shared. Decisions regarding the DoD information that must be shared to support completion of subcontractor tasks, will take place between the prime contractor and the subcontractors chosen to complete the specific tasks. The DoD encourages prime contractors to work with its subcontractors to flow down CUI with the required security and the least burden. The DoD declines to revise the rule to address responsibilities for derivative marking of CUI because this rule makes no change to DFARS clause 252.204-7012 or DoD's CUI policies regarding marking of CUI, including creation of information. The specific contractual language is part of the 48 CFR part 204 CMMC Acquisition rule and beyond the scope of this 32 CFR part 170 CMMC Program rule. This rule describes DoD's intent for CMMC Program requirements, which include that all prime and subcontractors at all tiers that process, store, or transmit CUI in the performance of a DoD contract (or sub-contract) are required to demonstrate compliance with the contract requirements (i.e., FAR clause 52.204-21 or DFARS clause 252.204-7012) for adequately safeguarding FCI or CUI. CMMC flow-down requirements are designed to apply consistent assessment requirements to all subcontractors, regardless of company size, who are required to adequately safeguard CUI. The DoD cannot dictate DIB business practices and encourages prime contractors to carefully consider the necessity of sharing CUI information and work with subcontractors to flow down CUI only when deemed appropriate. Likewise, the criteria by which contractors select CSPs for support or the availability of GFE for any particular contract are beyond the scope of this rule. The DoD declines to limit CMMC program requirements to the first-tier subcontractor, as suggested by the commenter. When a contractor or subcontractor responds to multiple solicitations, that contractor should complete the highest assessment level among them for the assessment scope defined for use in performance of the contracts. The contractor may also elect to structure its environment to meet differing CMMC requirements based on the contract(s) in question. Contractual remedies for non-compliance are a 48 CFR part 204 CMMC Acquisition rule matter and beyond the scope of this rule. c. Requirements Comment:

The Internet of Things (IoT) market is rapidly expanding, with the number of IoT devices expected to increase from 26 billion in 2019 to 75 billion in 2025 [1]. With this increase, IoT smart home technology is becoming more pervasive, with an annual growth of 31% [2] and 34% of broadband households forecasted to have smart home systems by 2025 [3]. While early adopters of smart home technology have typically been more technically savvy, smart home devices are increasingly being purchased by users who may not understand the technology's privacy and security implications [2]. Within the current dynamic threat and technology environment, the uptick of smart home technology adoption may expose users to increased risks to their network security, privacy of their information, and quite possibly their physical safety [4, 5]. As such, it is imperative that smart home consumers be able to protect the security and privacy of their devices while still being able to enjoy the benefits of the technology. Within the security context, participants mentioned that they were concerned about their devices being hacked by unauthorized or malicious actors, as expressed by one participant who worried that hackers would be able to 'shut o GLYPH<11> ; or

dismantle, or mess with the system that I have in place' (P37\A) . In fact, the threat of device exploitation underpinned many of the privacy and security concerns discovered in our study. For example, exploitation could lead to unauthorized individuals gaining access to audio and video feeds. Governments could hack into devices or their companion apps for surveillance purposes. One participant was concerned about smart home vulnerabilities in certain types of devices based on conversations he had with colleagues in which he learned 'each manufacturer is actually just borrowing security APIs instead of creating their own, and the APIs specifically have holes in them.

(3) If Army organizations are unable to comply with policy, they will immediately notify their superiors, who will submit a memorandum through the chain of command to the Administrative Assistant of the Secretary of the Army to explain why the affected individuals or population's personal information has been lost, stolen, or compromised. (4) This policy is also applicable to Army contractors who collect, maintain, use, or disseminate protected personal information on behalf of the organization. (f) Federal government contractors' compliance. (1) When a DA activity contracts for the design, development, or operation of a Privacy Act system of records in order to accomplish a DA mission, the agency must apply the requirements of the Privacy Act to the contractor and its employees working on the contract (See 48 CFR part 24 and other applicable supplements to the FAR; 32 CFR part 310). (2) System Managers will review annually, contracts contained within the system(s) of records under their responsibility, to determine which ones contain provisions relating to the design, development, or operation of a Privacy Act system of records. (3) Contractors are considered employees of the Army for the purpose of the sanction provisions of the Privacy Act during the performance of the contract requirements. (4) Disclosing records to a contractor for use in performing the requirements of an authorized DA contract is considered a disclosure within the agency under exception (b)(1), 'Official Need to Know', of the Act. § 505.3 Privacy Act systems of records. (a) Systems of records. (1) A system of records is a group of records under the control of a DA activity that are retrieved by an individual's name or by some identifying number, symbol, or other identifying particular assigned to an individual. (2) Privacy Act systems of records must be: (i) Authorized by Federal statute or an Executive Order; (ii) Needed to carry out DA's mission; and (iii) Published in the Federal Register in a system of records notice, which will provide the public an opportunity to (printed page 46056) comment before DA implements or changes the system. (3) The mere fact that records are retrievable by a name or personal identifier is not enough. Records must actually be retrieved by a name or personal identifier. Records in a group of records that may be retrieved by a name or personal identifier but are not normally retrieved by this method are not covered by this part. However, they are covered by AR 25-55, the Department of the Army Freedom of Information Act Program. (4) The existence of a statute or Executive Order mandating the maintenance of a system of records to perform an authorized activity does not abolish the responsibility to ensure the information in the system of records is relevant and necessary to perform the authorized activity. (b) Privacy Act system of records notices. (1) DA must publish notices in the Federal Register

1 OT includes hardware and software that use direct monitoring and control of industrial equipment to detect or cause a change. Additional Guidance on Level 2 Scoping CMMC Assessment Scope · Level 2 | Version 2.13 8 Specialized Assets are part of the CMMC Assessment Scope. In accordance with 32 CFR § 170.19(c)(1) Table 3, the OSA shall document these assets in the SSP and detail how they are managed using the OSA's risk-based information security policy, procedures, and practices. In addition, the OSA is required to: · document each asset in asset inventory; there is no requirement to embed every asset in the SSP; · document these assets in the SSP to show they are managed using the OSA's risk-based security policies, procedures, and practices; and · provide a network diagram of the CMMC Assessment Scope (to include these assets) to facilitate scoping discussions during the pre-assessment. An assessor will review the SSP to verify that specialized assets are managed using the OSA's risk-based information security policy, procedures, and practices , and accounted for within the OSA's CMMC Assessment Scope. The assessor will not retain a copy of the SSP. Out-of-Scope Assets Out-of-Scope Assets cannot process, store, or transmit CUI, and do not provide security protections for CUI Assets. Assets that are physically or logically separated from CUI Assets and do not provide security protections for CUI Assets are also Out-of-Scope Assets. An asset that falls into any in-scope asset category cannot be considered an Out-of-Scope Asset. In accordance with 32 CFR § 170.19(c)(1), Out-of-Scope Assets are not part of a Level 2 self-assessment or certification assessment. There are no documentation requirements for Out - of-Scope Assets. Defining the CMMC Assessment Scope After categorizing its assets, the OSA then specifies the CMMC Assessment Scope. The CMMC Assessment Scope includes all assets in the OSA's environment

that will be assessed in accordance with Table 1. OSAs will be required to provide documentation that specifies the CMMC Assessment Scope to the assessor. Details about required documentation for each asset category can be found in the CMMC Asset Categories section above. The following asset categories are part of the Level 2 CMMC Assessment Scope: · CUI Assets · Security Protection Assets · Contractor Risk Managed Assets · Specialized Assets

Once CMMC is fully implemented, certain DoD contractors that handle sensitive unclassified DoD information will be required to achieve a particular CMMC level as a condition of contract award. In September 2020, the DoD published an interim DFARS rule in the Federal Register (DFARS Case 2019-D041) that implemented the DoD's initial vision for the CMMC Program (·CMMC 1.0·) and outlined the basic features of the program (tiered model, required assessments, and implementation through contracts). The interim rule became effective on November 30, 2020. In March 2021, the Department initiated an internal review of CMMC's implementation, informed by more than 750 public comments in response to the interim DFARS rule. This comprehensive, programmatic assessment engaged cybersecurity and acquisition leaders within DoD to refine policy and program implementation. In November 2021, the Department announced ·CMMC 2.0,· which is an updated program structure and revised requirements designed to achieve the primary goals of an internal DoD review of the CMMC Program. With the implementation of CMMC 2.0, the Department introduced several key changes that build on and refine the original program requirements. These include: Streamlining the model from five levels to three levels. Exclusively implementing National Institute of Standards and Technology (NIST) cybersecurity guidelines. Allowing all companies at Level 1 and a subset of companies at Level 2 to demonstrate compliance through self-assessments. Increased oversight of professional and ethical standards of third-party assessors. Allowing companies, under limited circumstances, to make Plan of Action & Milestones (POA&M) to achieve certification. In July 2022, the CMMC PMO met with the Office of Advocacy for the U.S. SBA to address the revisions planned in CMMC 2.0 that are responsive to prior SBA concerns. As a result of the alignment of CMMC 2.0 to NIST guidelines, the Department's requirements will continue to evolve as changes are made to the underlying NIST SP 800-171 Rev 2 and NIST SP 800-172 requirements. (2) Objectives of, and Legal Basis for, the Rule Legal Basis: 5 U.S.C. 301 ; Sec. 1648, Public Law 116-92 , 133 Stat. 1198. The objective of this proposed rule (CMMC Program rule) is to provide the Department with increased assurance that a defense contractor can adequately protect sensitive unclassified information commensurate with the risk, accounting for information flow down to its subcontractors in a multi-tier supply chain. This rule meets the objective by providing a mechanism to assess contractor and subcontractor implementation of DoD's cyber security protection requirements for FCI and CUI. Implementation of the CMMC Program is intended to address the following policy issues: (a) Verification of a Contractor's Cybersecurity Posture Effective June 2016, FAR clause 52.204-21 Basic Safeguarding of Contractor Information Systems,

This applies when the disclosure of law enforcement records would disclose techniques and procedures for law enforcement investigations or prosecutions, or would disclose guidelines for law enforcement investigations or prosecutions, if such disclosure could reasonably be expected to risk circumvention of the law (5 U.S.C. 552(b)(7)(E)). (vi) Exemption 7F. This applies when the disclosure of law enforcement records could reasonably be expected to endanger the life or physical safety of any individual (5 U.S.C. 552(b)(7)(F)). (2) Examples of Exemption 7 applications. (i) Statements of witnesses and other material developed during the course of the investigation and all materials prepared in connection with related Government litigation or adjudicative proceedings may be exempt from disclosure pursuant to Exemptions 7A, 7C, and/or 7D. (ii) The identity of firms or individuals being investigated for alleged irregularities involving contracting with the Department of Defense when no indictment has been obtained nor any civil action filed against them by the United States may be exempt from disclosure pursuant to Exemptions 7A and/or 7C. (iii) Information obtained in confidence, expressed or implied, in the course of a criminal investigation by a criminal law enforcement agency or a lawful national security intelligence (printed page 71857) investigation, may be exempt from disclosure pursuant to Exemptions 7A, 7C and/or 7D. National security intelligence investigations include background security investigations and those investigations conducted for the purpose of obtaining affirmative or counterintelligence information. (iv) Emergency action plans, guidelines for response to terrorist attacks, analyses of security procedures, and other sensitive information that could prove deadly if obtained by those seeking to do harm to the public on a large scale may be exempt from disclosure pursuant to Exemptions 7E and/or 7F. The Components should also assert Exemption 2 in conjunction with Exemption 7E to withhold this type of law enforcement information. (3) Exclusions. The FOIA contains 3

special protection provisions referred to as record exclusions. Of these exclusions, only 2 are used by the Department of Defense. These exclusions expressly authorize Department of Defense law enforcement agencies to treat especially sensitive records under certain specified circumstances as not subject to the requirements of the FOIA. The DoD Component considering invoking one of these exclusions shall first consult with legal counsel and with DFOIPO. In turn, DFOIPO will consult with the Office of Information and Privacy, Department of Justice. If the records are determined to be excluded, the response to the requester will state that no records were found. (i) Exclusion 1. The DoD Components may treat records requested as not subject to the FOIA when the following circumstance applies: (A) The request involves access to records or information compiled for law enforcement purposes.

(ii) Home addresses and phone numbers; or (iii) Date of birth. (i) Disclosures for established routine uses. (1) Records may be disclosed outside the DOD without the consent of the individual to whom they pertain for an established routine use. (2) A routine use shall (i) Be compatible with and related to the purpose for which the record was compiled; (ii) Identify the persons or organizations to which the records may be released; and (iii) Have been published previously in the Federal Register. (3) Establish a routine use for each user of the information outside the Department of Defense who needs official access to the records. (4) Routine uses may be established, discontinued, or amended without the consent of the individuals involved. However, new or changed routine uses must be published in the Federal (printed page 24506) Register at least 30 days before actually disclosing any records. (5) In addition to the routine uses listed in the applicable systems of records notices, Blanket Routine Uses for all DOD maintained systems of records have been established. These Blanket Routine Uses are applicable to every record system maintained within the DOD unless specifically stated otherwise within a particular record system. The Blanket Routine Uses are listed at appendix C of this part. (j) Disclosure accounting. (1) System managers must keep an accurate record of all disclosures made from DA Privacy Act system of records, including those made with the consent of the individual, except when records are (i) Disclosed to DOD officials who have a need to know the information to perform official government duties; or (ii) Required to be disclosed under the Freedom of Information Act. (2) The purpose for the accounting of disclosure is to (i) Enable an individual to ascertain those persons or agencies that have received information about them; (ii) Enable the DA to notify past recipients of subsequent amendments or Statements of Dispute concerning the record; and (iii) Provide a record of DA compliance with the Privacy Act of 1974, if necessary. (3) Since the characteristics of records maintained within DA vary widely, no uniform method for keeping the disclosure accounting is prescribed. (4) Essential elements to include in each disclosure accounting report are (i) The name, position title, and address of the person making the disclosure; (ii) Description of the record disclosed; (iii) The date, method, and purpose of the disclosure; and (iv) The name, position title, and address of the person or agency to which the disclosure was made. (5) The record subject has the right of access to the disclosure accounting except when (i) The disclosure was made for law enforcement purposes under 5 U.S.C. 552a(b)(7); or (ii) The disclosure was made from a system of records for which an exemption from 5 U.S.C. 552a(c)(3) has been claimed.

3.5.2 | Sandboxing... 3.5.2 Sandboxing Sandboxing refers to a security model where applications are run within a sandbox-a controlled environment that restricts what operations the applications can perform and that isolates them from other applications running on the same host.

Function Unique Identifier	Function	Category Unique Identifier	Category
----- ----- ----- -----			
-----	ID-P Identify-P ID.IM-P Inventory and Mapping	ID-P Identify-P	
ID.BE-P Business Environment	ID-P Identify-P ID.RA-P Risk Assessment	ID-P	
Identify-P ID.DE-P Data Processing Ecosystem Risk Management	GV-P Govern-P GV.PO-P Governance Policies, Processes, and Procedures	GV-P Govern-P GV.RM-P Risk Management Strategy	GV-P Govern-P GV.AT-P Awareness and Training
GV-P Govern-P GV.MT-P Monitoring and Review	CT-P Control-P CT.PO-P Data Processing Policies, Processes, and Procedures	CT-P Control-P	
CT.DM-P Data Processing Management	CT-P Control-P		
CT.DP-P Disassociated Processing	CM-P Communicate-P CM.PO-P Communication Policies, Processes, and Procedures	CM-P Communicate-P CM.AW-P Data Processing Awareness	PR-P Protect-P
PR.PO-P Data Protection Policies, Processes, and Procedures	PR-P Protect-P		
PR.AC-P Identity Management, Authentication, and Access Control	PR-P Protect-P PR.DS-P Data Security		

The following is the annual small entities total cost summary for CMMC Level 1 self-assessments and affirmations over a ten-year period: (Example calculation, Year 1: $\$5,977$ per entity (detailed above) $\times$ 699 entities (cumulative) = $\$4,177,845$) (printed page 83206) CMMC Level 2 Self-Assessment and Affirmation Costs for Small Business Entities The costs below account for a CMMC Level 2 self-assessment of the applicable contractor information system(s) with NIST SP 800-171 R2 requirements based on assumptions defined above. Nonrecurring and recurring engineering costs: There are no nonrecurring or recurring engineering costs associated with CMMC Level 2 self-assessment since it is assumed the contractor has implemented NIST SP 800-171 R2 requirements. Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 2 self-assessment and affirmation for a small entity is $\$34,277$. The three-year cost is $\$37,196$ (as summarized in 4.1.2 above, table 2), which includes the triennial assessment + affirmation, plus two additional annual affirmations ($\$34,277 + \$1,459 + \$1,459$). · Phase 1: Planning and preparing for the self-assessment: $\$14,426$ A director (MGMT5) for 32 hours ($\$190.52/\text{hr} \times 32\text{hrs} = \$6,097$) An external service provider (ESP) for 32 hours ($\$260.28/\text{hr} \times 32\text{hrs} = \$8,329$) · Phase 2: Conducting the self-assessment: $\$15,542$ A director (MGMT5) for 16 hours ($\$190.52/\text{hr} \times 16\text{hrs} = \$3,048$) An external service provider (ESP) for 48 hours ($\$260.28/\text{hr} \times 48\text{hrs} = \$12,493$) · Phase 3: Reporting of assessment results: $\$2,851$ A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) An external service provider (ESP) for 8 hours ($\$260.28/\text{hr} \times 8\text{hrs} = \$2,082$) A staff IT specialist (IT4) for 0.08 hours ($\$86.24/\text{hr} \times 0.08\text{hrs} = \7) · Affirmation ·initial affirmation post assessment: $\$1,459$ Reaffirmations: It is estimated that the costs to reaffirm a CMMC Level 2 self-assessment annually is $\$1,459$ (three-year costs to reaffirm a CMMC Level 2 self-assessment annually is $\$4,377$, or $\$1,459 \times 3$): ·A director (MGMT5) for 4 hours ($\$190.52/\text{hr} \times 4\text{hrs} = \762) ·A staff IT specialist (IT4) for 8.08 hours ($\$86.24/\text{hr} \times 8.08\text{hrs} = \697) Summary: The following is the annual small entities total cost summary for CMMC Level 2 self-assessments and Affirmations over a ten-year period: (Example calculation, Year 2: ($\$34,277$ self-assessment per entity $\times$ 101 entities) + ($\$1,459$ annual affirmation per entity $\times$ 20 entities) = $\$3,491,193$) (printed page 83207) CMMC Level 2 Certification and Affirmation Costs for Small Business Entities The costs below account for a CMMC Level 2 Certification assessment and affirmation costs of the applicable contractor information system(s) with NIST SP 800-171 R2 requirements based on assumptions defined above. CMMC Level 2 certification assessments require hiring a C3PAO to perform the assessment. Nonrecurring or recurring engineering costs:

The analysis of the benefits of the final rule uses characteristics of conventional outbreaks and investigations to more clearly identify and quantify shortfalls in existing recordkeeping practices and how each is addressed by the recordkeeping regulation. We measure the effects in terms of the number of illnesses averted due to reductions in the duration of outbreak investigations and reductions in the number of investigations that are prematurely terminated because of poor records quality. When an investigation is prematurely terminated, there is both a loss of data that might prevent recurrences of the outbreak and a decrease in the effectiveness of any preventive action. The need for this regulation is underscored when the potentially large sizes of outbreaks from intentional attacks on the food supply are considered. Although the probability of such an intentional attack is unknown, the size of the benefits from this regulation are larger, the larger the size of such an outbreak. We estimate benefits using data from FDA outbreak investigations. We then compared estimated benefits for a number of regulatory options. In this way, the benefits of each regulatory option can be compared to its costs. While the costs and benefits of the policy alternative ·not to regulate· are not considered in the final rule, they were analyzed in the proposed rule. We did not estimate the effects of potential future regulatory actions because we do not anticipate any such actions that would affect the estimated costs or benefits of this final rule. In response to the comment that we have not shown that benefits exceed costs, the Executive Order requires that costs must be justified by benefits. We believe we have done so in this analysis. Finally, in the PRIA, FDA addressed the state of the national economy by examining the impact of the final rule on the most vulnerable firms in the industry, through simulations using our small business model (Ref 1.), and also in the Unfunded Mandates section by examining the impact of the rule on all consumers as well as producers in the food economy in general. In this analysis we use the small business model to calculate the effects of the costs of this final rule on the survival of small businesses. We incorporated both the annualized one-time costs and the recurring costs for computing the effects on cash flows. We computed the effects for firms manufacturing dietary supplements, candy, and ready-to-eat foods, including breakfast cereals, beverages, canned foods, baked items and breads, and dressings and sauces. While these firms do not represent every

category of food establishment covered by this final rule, they do reflect a large number of firms in the food industry, including manufacturers, input suppliers, and distributors. FDA assumes that the cost and revenue structures of firms not explicitly included in the computation of the model do not differ substantially from those that are included.

means assets that cannot process, store, or transmit CUI because they are physically or logically separated from information systems that do process, store or transmit CUI, or are inherently unable to do so; except for assets that provide security protection for a CUI asset (see the definition for Security Protection Assets). (CMMC-custom term) Periodically means occurring at regular intervals. As used in many requirements within CMMC, the interval length is organization-defined to provided OSA flexibility, with an interval length of no more than one year. (CMMC-custom term) Plan of action and milestones (POA&M) means a document that identifies tasks needing to be accomplished. It details resources required to accomplish the elements of the plan, any milestones in meeting the tasks, and scheduled completion dates for the milestones, as defined in NIST SP 800-115 (incorporated by reference, see § 170.2). Prime Contractor is defined in 48 CFR 3.502-1 . Process, store, or transmit means data can be used by an asset (e.g., accessed, entered, edited, generated, manipulated, or printed); data is inactive or at rest on an asset (e.g., located on electronic media, in system component memory, or in physical format such as paper documents); or data is being transferred from one asset to another asset (e.g., data in transit using physical or digital transport methods). (CMMC-custom term) Restricted Information Systems means systems (and associated IT components comprising the system) that are configured based on government requirements (e.g., connected to something that was required to support a functional requirement) and are used to support a contract (e.g., fielded systems, obsolete systems, and product deliverable replicas). (CMMC-custom term) Risk means a measure of the extent to which an entity is threatened by a potential circumstance or event, and typically a function of the adverse impacts that would arise if the circumstance or event occurs and the likelihood of occurrence, as defined in CNSSI 4009 (incorporated by reference, see § 170.2). Risk Assessment means the process of identifying risks to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the Nation, resulting from the operation of a system. Risk Assessment is part of risk management, incorporates threat and vulnerability analyses, and considers mitigations provided by security controls planned or in place. Synonymous with risk analysis, as defined in NIST SP 800-39 (incorporated by reference, see § 170.2). Security Protection Assets means assets providing security functions or capabilities to the OSA's CMMC Assessment Scope, irrespective of whether or not these assets process, store, or transmit CUI. (CMMC-custom term) Specialized Assets

facilities covered by the regulation by not identifying transporters of food contact materials, and that the 20 NAICS codes do not cover all food packaging manufacturers and distributors. Several comments state that all packaging firms handle both outer packaging and food contact substances, and for all practical purposes, will have to track all products they produce, because they may not know if a shipment is destined for food or nonfood use. One comment states that FDA's count of foreign facilities from OASIS did not include all imported food contact substances. (Response) The final rule does not require persons who manufacture, process, pack, transport, distribute, import, receive, or hold packaging (the outer packaging of food that bears the label and does not contact the food) to establish or maintain records. However, these persons are subject to the records access requirements with respect to any existing records if they also engage in another regulated activity with respect to the food in, or to be placed in, such packaging. Persons who place food directly in contact with its finished container are subject to all of the requirements of subpart J as to the finished container that directly contacts that food. Moreover, all other persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that directly contacts the food are excluded from the establishment and maintenance requirements with regard to the finished container, and are only subject to the records access provisions for existing records under §§ 1.361 and 1.363. In the final rule, records access costs are estimated to be zero and we assume that the only costs incurred by persons who manufacture, process, pack, transport, distribute, receive, hold, or import the finished container that directly contacts the food are learning costs. Because the economic burden on these facilities in the final rule has been substantially reduced from that estimated in the PRIA, we assume that the impact on costs of any possible underestimation of their numbers will be very small. e. Foreign facilities and related impacts . (Comment 212) There were many comments that state that the expansion of requirements to foreign facilities would have a large impact on international trade by making imports more

expensive. Some comments state that costs for compliance by developing countries were underestimated in the PRIA because their labor and technology are so different from those that prevail in developed countries.

(i) For the purpose of monitoring alarms, an equivalent level of monitoring service is available from multiple types of providers. The central monitoring station may be located at a one of the following: (A) Government contractor monitoring station (GCMS), formerly called a proprietary central station. (B) Cleared commercial central station. (C) Cleared protective signal service station (e.g., fire alarm monitor). (D) Cleared residential monitoring station. (E) National industrial monitoring station. (ii) SECRET-cleared central station employees at the alarm monitoring station will be in attendance in sufficient number to monitor each alarmed area within the cleared contractor facility. (iii) The central monitoring station will be supervised continuously by a U.S. citizen who has eligibility for access to SECRET information. (iv) The IDS must be activated at the close of business whenever the area is not occupied by cleared personnel. Any IDS exit delay function must expire prior to the cleared personnel leaving the immediate area. A record will be maintained to identify the person or persons who are responsible for setting and deactivating the IDS. (v) Records will be maintained for 12 months indicating time of receipt of alarm, name(s) of security force personnel responding, time dispatched to facility or area, time security force personnel arrived, nature of alarm, and what follow-up actions were accomplished. (3) Investigative response to alarms. (i) Alarm response teams will ascertain if intrusion has occurred and, if possible, assist in the apprehension of the individuals involved. (A) If an alarm activation resets in a reasonable amount of time and no damage to the area is visible, then entrance into the area is not required and an initial response team may consist of uncleared personnel. (B) If the alarm activation does not reset and damage is observed, then a cleared response team must be dispatched. The initial uncleared response team must stay on station until relieved by the cleared response team. If a cleared response team does not arrive within 1 hour, then a report to the CSA must be made by the close of the next business day. (ii) The following resources may be used to investigate alarms: Proprietary security force personnel, central station guards, local law enforcement personnel, or a subcontracted guard service. The CSA may approve procedures for the use of entity cleared employees who can meet the minimum response requirements outlined in this section. (A) For a GCMS, trained proprietary or subcontractor security force personnel, cleared to the SECRET level and sufficient in number to be dispatched immediately to investigate each alarm, will be available at all times when the IDS is in operation.

- Sequencers are typically connected to a network and the internet. This provides access to the manufacturer for updates and transfer of files to secure storage. There is no guidance on the network addresses and the corresponding network protocols that are required for sequencers to effectively operate. The development of DLP guidance specifically developed for the sector would prevent the unwarranted flow of information and provide data confinement. For example, it would be possible to microsegment sequencers on the network, providing them with only the required resources for their proper functioning in keeping with ZTA cybersecurity principles. This would mitigate the possibilities of adversaries exploiting vulnerabilities in the sequencer's hardware or software for exfiltration of data as well as using the sequencers as entry points that allow lateral movement throughout the enterprise network. Another control is to use current technical solutions regarding data confinement offering protective controls that prevent exfiltration to non-permitted internet protocol (IP) addresses, such as cloud features that can create a secure perimeter. - The potential loss of patient and sample information, credentials, and other private information can be partially addressed by the requirement of 'device reset' functionality to delete critical data and stored credentials from the equipment without affecting the operational state, which is particularly important when decommissioning an instrument. Also, users should be able to reinstall or update software for safely resetting instruments and eliminating stored data. - Most genetic data sharing and processing occurs in cloud environments, frequently leveraging containers (e.g., Docker or Pods). Many cybersecurity vulnerability scanners are not optimized for scanning containers, resulting in an inability to identify certain vulnerabilities and a high number of false positives.

Several respondents commented on the need for DoD to focus on mitigation plans and less intrusive measures. One of these respondents commented that DoD should create a mechanism for vendors to file supply chain risk mitigation plans with DoD. DoD could take these plans into consideration when assessing supply chain risk for any particular procurement activity. By viewing filed mitigation plans from multiple vendors, DoD could gain greater insight into commercially viable supply chain

mitigation practices. This respondent further stated that DoD should approach supply chain risk with an eye toward encouraging mitigation rather than simply disqualifying vendors, suggesting that DoD can and should implement robust supply chain security practices. One respondent suggested that DoD should clarify what it believes are less intrusive measures under section 239.7304(b)(1)(2), recommending that in order to prevent the interim rule from impeding the use of commercial technology (including commercially available off-the-shelf items) in NSS, which ultimately benefits DoD, the Department should provide wide discretion to the judgment of manufacturers in their use of industry standards and internal processes to meet its supply chain risk goals. This respondent further commented that while DFARS section 239.7304 of the rule provides that an exclusion under DFARS 239.7305 may occur when it is determined that, among other factors, 'less intrusive measures are not reasonably available to reduce such supply chain risk,' at no point in the rule is clarity provided on what this language is defined as or what an authorized individual should refer to in order to gauge what 'less intrusive measures' are and whether they are 'not reasonably available.' Another of these respondents suggested that the opportunity to mitigate or eliminate the noticed risk from the supply chain would avoid significant costs that would be passed along to DoD. One respondent suggested that DoD modify the interim rule to clarify that the exercise of the authorities under DFARS 239.7305 should be a 'last resort,' invoked only after other methods of mitigating supply chain risk have been considered or attempted. Response: Section 806(b)(2) requires that 'less intrusive measures are not reasonably available to reduce supply chain risk' to use its authority. Whenever it is appropriate, DoD will work with its offerors to mitigate supply chain risk using less intrusive measures than exclusion based on section 806 authorities. In the notification to congressional committees when exercising section 806 authority, a summary of the mitigation analysis evaluating reasonably available mitigations will be documented. In most cases, DoD expects these mitigations will sufficiently mitigate the risks so that exclusion will not be necessary. e. Standards and Controls Comment:

From the NIST SP 800-172 Rev 3 Final Public Draft: b. Employ the threat-hunting capability [Assignment: organization-defined frequency]. DISCUSSION Threat hunting is an active means of cyber defense in contrast to traditional protection measures, such as firewalls, intrusion detection and prevention systems, quarantining malicious code in sandboxes, and Security Information and Event Management (SIEM) technologies and systems. Cyber threat hunting involves proactively searching organizational systems, networks, and infrastructure for advanced threats. The objective is to track and disrupt adversaries as early as possible in the attack sequence and to measurably improve the speed and accuracy of responses. Indications of compromise include unusual network traffic, unusual file changes, and the presence of malicious code. Threat-

The DoD declined to produce another cost estimate for CMMC assessment and certification. As required by the Rulemaking Guidance, the DoD provided cost estimates and impact analyses in the proposed rule. The analysis included estimated costs for each level and type of assessment or certification for different sized contractor businesses. The cost estimates did not include an analysis of profit margins, which is not required. This rule also does not provide the cost analysis for all actions, personnel, and security measures required to protect CUI information, data, systems, and technical products through the life cycle of the work and data generated. The cost estimates represent derived estimates based on internal expertise and public feedback in accordance with OMB Circular A-4. Market forces of supply and demand will determine C3PAO pricing for CMMC Level 2 certification assessments. The size and complexity of the network within scope of the assessment impacts the costs as well. CMMC Level 3 assessments against the NIST SP 800-172 Feb2021 baseline are performed free of cost by DoD assessors, which reduces the cost of CMMC Level 3. The costs associated with a government-owned SECRET-level network are not relevant to the CMMC Program which ensures protection of FCI and CUI. e. Assistance Programs or Other Relief Comment: Several commenters proposed that financial assistance, contract incentives, direct reimbursement of assessment costs (in whole or in part), and market rate price caps be considered to lessen financial burden and decrease the entry barrier for SMBs. Several comments also inquired about DoD SMB grant programs to help SMBs cover the cost of CMMC Level 2 certification assessments. Multiple comments suggested DOD provide actionable guidance through outreach support and assistance along with free or reduced cost cybersecurity services to SMBs, with two referencing the DoD Office of Small Business Programs and one the DoD Procurement Toolbox. One comment, from a large business with SMB suppliers, requested clearer guidance and support for flow down to sub-tier suppliers and SMB supply chains. One comment stated firms who receive a low number of CUI documents (30 docs in 3-years on 10 computers) do not justify the cost of becoming CMMC compliant, and added the cost is nearly as much as protection for

classified documents. One commenter suggested NIST SP 800-171 R2 security requirements would not apply to their specific characteristics, i.e., a very small (printed page 83152) business with minimal internet connectivity, no remote access, no public access, no mobile devices, no remote work, and no known cybersecurity issues. The comment asserted that the company posed minimal risk to CUI and should be excused from adhering to CMMC program requirements based on cost burden.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. Figure 1 depicts a notional enterprise with subordinate organizations, illustrating that one of those subordinate organizations is itself an enterprise. Both government and industry are represented in this depiction. Consider the example of the Department of Commerce as a higherlevel enterprise with bureaus (e.g., Census Bureau, National Oceanic and Atmospheric Administration [NOAA], NIST) as lower-level enterprises and subordinates (e.g., NOAA's National Weather Service, NIST laboratories) representing organizations.

3.1.6 | Human Error and Deliberate Misconfiguration... 3.1.6 Human Error and Deliberate Misconfiguration Even with the existence of security controls, users may end up performing technically supported storage configuration changes that still present an unacceptable exposure (e.

As of 2026, the DFARS cybersecurity clause landscape is as follows: - DFARS 252.204-7012 (Safeguarding Covered Defense Information): Active. Requires contractors to implement NIST SP 800-171 and report cyber incidents within 72 hours. - DFARS 252.204-7019 (Notice of NIST SP 800-171 DoD Assessment Requirements): Eliminated as of February 1, 2026. Basic self-assessment SPRS uploads no longer required. - DFARS 252.204-7020 (NIST SP 800-171 DoD Assessment Requirements): Active. Governs Medium and High assessments conducted by DIBCAC. - DFARS 252.204-7021 (CMMC Requirements): Active as of November 10, 2025 (Phase 1). Requires CMMC certification at the level specified in the contract. The elimination of 7019 consolidates assessment requirements under the CMMC framework.

would require a regulated entity to establish written policies and procedures for retaining and reviewing records of activity in the regulated entity's relevant electronic information systems by persons and technology assets. Such written policies and procedures should require review of activity in the regulated entity's relevant electronic information systems as a whole, as well as the system's components, including but not limited to any workstations. They should also include information on the frequency for reviewing such records. The frequency of review may vary based on the specific type of record being reviewed and the information it contains. According to the proposed implementation specification for scope at proposed 45 CFR 164.308(a)(7)(ii)(B) , records of activity in the regulated entity's relevant electronic information systems by persons and technology assets would include, but would not be limited to, audit trails, event logs, firewall logs, system logs, data backup logs, access reports, anti-malware logs, and security incident tracking reports. The proposed implementation specification for records review at proposed 45 CFR 164.308(a)(7)(ii)(C) would require a regulated entity to review records of activity in its relevant electronic information systems by persons and technology assets as often as reasonable and appropriate for the type of report or log. They would also be required to document such review. A proposed implementation specification for record retention at proposed 45 CFR 164.308(a)(7)(ii)(D) would require a regulated entity to retain records of activity in its relevant electronic information systems by persons and technology assets. Under the proposal, the regulated entity would be required to retain such records for an amount of time that is reasonable and appropriate for the specific type of report or log. For example, it may be reasonable and appropriate to retain audit trails for a different amount of time than security incident tracking reports because of the type of

information they contain and their purpose. The proposed implementation specification for response at proposed 45 CFR 164.308(a)(7)(ii)(E) would require a regulated entity to respond to a suspected or known security incident identified during the review of activity in its relevant electronic information systems, including any components thereof, such as workstations, in accordance with the regulated entity's security incident plan. [541] Finally, the proposed implementation specification for maintenance at proposed 45 CFR 164.308(a)(7)(ii)(F) would require a regulated entity to review and test its written policies and procedures for reviewing activity in its relevant electronic information systems at least once every 12 months. The regulated entity would be expected to modify such policies and procedures as reasonable and appropriate, based on the results of that review.

(b) The requirements of this part do not apply to Federal information systems operated by contractors or subcontractors on behalf of the Government. (c) CMMC Program requirements apply to all DoD solicitations and contracts pursuant to which a defense contractor or subcontractor will process, store, or transmit FCI or CUI on unclassified contractor information systems, including those for the acquisition of commercial items (except those exclusively for COTS items) valued at greater than the micro-purchase threshold except under the following circumstances: (1) The procurement occurs during Implementation Phase 1, 2, or 3 as described in paragraph (e) of this section, in which case CMMC Program requirements apply in accordance with the requirements for the relevant phase-in period; or (2) Application of CMMC Program requirements to a procurement or class of procurements may be waived in advance of the solicitation at the discretion of DoD in accordance with all applicable policies, procedures, and approval requirements. (d) DoD Program Managers or requiring activities are responsible for selecting the CMMC Status that will apply for a particular procurement or contract based upon the type of information, FCI or CUI, that will be processed on, stored on, or transmitted through a contractor information system. Application of the CMMC Status for subcontractors will be determined in accordance with § 170.23. (e) DoD is utilizing a phased approach for the inclusion of CMMC Program requirements in solicitations and contracts. Implementation of CMMC Program requirements will occur over four (4) phases: (1) Phase 1. Begins on the effective date of the complementary 48 CFR part 204 CMMC Acquisition final rule. DoD intends to include the requirement for CMMC Statuses of Level 1 (Self) or Level 2 (Self) for all applicable DoD solicitations and contracts as a condition of contract award. DoD may, at its discretion, include the requirement for CMMC Status of Level 1 (Self) or Level 2 (Self) for applicable DoD solicitations and contracts as a condition to exercise an option period on a contract awarded prior to the effective date. DoD may also, at its discretion, include the requirement for CMMC Status of Level 2 (C3PAO) in place of the Level 2 (Self) CMMC Status for applicable DoD solicitations and contracts. (2) Phase 2. Begins one calendar year following the start date of Phase 1. In addition to Phase 1 requirements, DoD intends to include the requirement for CMMC Status of Level 2 (C3PAO) for applicable DoD solicitations and contracts as a condition of contract award. DoD may, at its discretion, delay the inclusion of requirement for CMMC Status of Level 2 (C3PAO) to an option period instead of as a condition of contract award. DoD may also, at its discretion, include the requirement for CMMC Status of Level 3 (DIBCAC) for applicable DoD solicitations and contracts. (3) Phase 3.

(F) From subsections (e)(4)(G), (e)(4)(H), and (e)(4)(I) (Agency Requirements) and (f) (Agency Rules), because portions of this system are exempt from the individual access provisions of subsection (d) for the reasons noted above, and therefore NGA is not required to establish requirements, rules, or procedures with respect to such access. Providing notice to individuals with respect to existence of records pertaining to them in the system of records or otherwise setting up procedures pursuant to which individuals may access and view records pertaining to themselves in the system would undermine investigative efforts and reveal the identities of witnesses, and potential witnesses, and confidential informants. (G) From subsection (e)(5) (Collection of Information) because with the collection of information for law enforcement purposes, it is impossible to determine in advance what information is accurate, relevant, timely, and complete. Compliance with subsection (e)(5) would preclude NGA personnel from using their investigative training and exercise of good judgment to both conduct and report on investigations. (H) From subsection (e)(8) (Notice on Individuals) because compliance would interfere with NGA's ability to cooperate with law enforcement who would obtain, serve, and issue subpoenas, warrants, and other law enforcement mechanisms that may be filed under seal and could result in disclosure of investigative techniques, procedures, and evidence. (I) From subsection (g)(1) (Civil Remedies) to the extent that the system is exempt from other specific subsections of the Privacy Act. (5) System identifier and name.

NGA-010, National Geospatial-Intelligence Agency Security Financial Disclosure Reporting Records System. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a (printed page 14785) confidential source. When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Investigative material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5). (iii) Reasons. Pursuant to 5 U.S.C. 552a(k)(2), and (k)(5)

From the NIST SP 800-172 Rev 3 Final Public Draft: · Damage-limiting operations: Procedural and operational measures that use system capabilities to maximize the ability of an organization to detect successful system compromises by an adversary and to limit the effects of such compromises (both detected and undetected). NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 · Cyber resiliency: The ability to anticipate, withstand, recover from, and adapt to adverse 297

NIST SP 800-171 Rev 3 (published May 2024) is the current version. Key changes from Rev 2: - Reorganized from 14 to 17 control families - Updated control numbering (3.X.X format to 03.XX.XX format) - Added new controls for supply chain risk management - Introduced Organization-Defined Parameters (ODPs) - Better alignment with NIST SP 800-53 Rev 5 - 97 security requirements (vs 110 in Rev 2 when counting sub-requirements) The DoD is transitioning to Rev 3 for CMMC assessments. Check with your contracting officer for the current requirement in your specific contract.

to control information flows between security domains on connected systems. (iii) AT.L3-3.2.1e Provide awareness training upon initial hire, following a significant cyber event, and at least annually, focused on recognizing and responding to threats from social engineering, advanced persistent threat actors, breaches, and suspicious behaviors; update the training at least annually or when there are significant changes to the threat. (iv) AT.L3-3.2.2e Include practical exercises in awareness training for all users, tailored by roles, to include general users, users with specialized roles, and privileged users, that are aligned with current threat scenarios and provide feedback to individuals involved in the training and their supervisors. (v) CM.L3-3.4.1e Establish and maintain an authoritative source and repository to provide a trusted source and accountability for approved and implemented system components. (vi) CM.L3-3.4.2e Employ automated mechanisms to detect misconfigured or unauthorized system components; after detection, remove the components or place the components in a quarantine or remediation network to facilitate patching, re-configuration, or other mitigations. (vii) CM.L3-3.4.3e Employ automated discovery and management tools to maintain an up-to-date, complete, accurate, and readily available inventory of system components. (viii) IA.L3-3.5.1e Identify and authenticate systems and system components, where possible, before establishing a network connection using bidirectional authentication that is cryptographically based and replay resistant. (ix) IA.L3-3.5.3e Employ automated or manual/procedural mechanisms to prohibit system components from connecting to organizational systems unless the components are known, authenticated, in a properly configured state, or in a trust profile. (x) IR.L3-3.6.1e Establish and maintain a security operations center capability that operates 24/7, with allowance for remote/on-call staff. (xi) IR.L3-3.6.2e Establish and maintain a cyber-incident response team that can be deployed by the organization within 24 hours. (xii) PS.L3-3.9.2e Ensure that organizational systems are protected if adverse information develops or is obtained about individuals with access to CUI. (xiii) RA.L3-3.11.1e Employ threat intelligence, at a minimum from open or commercial sources, and any DoD-provided sources, as part of a risk assessment to guide and inform the development of organizational systems, security architectures, selection of security solutions, monitoring, threat hunting, and response and recovery activities. (xiv) RA.L3-3.11.2e Conduct cyber threat hunting activities on an on-going aperiodic basis or when indications warrant, to search for indicators of compromise in organizational systems and detect, track, and disrupt threats that evade existing controls. (xv) RA.L3-3.11.3e Employ advanced automation and analytics capabilities in support of analysts to predict and identify risks to

organizations, systems, and system components. (xvi) RA.L3-3.11.4e

(v) Only persons with appropriate training may review matter to determine if it contains TFNI. Training must be completed prior to making determinations and every two years after. The training must include the content for persons with access to TFNI and the following: (A) The markings applied to matter containing TFNI. (B) Limitations on their authority to remove TFNI portions from matter. (C) Only DOE authorized persons may determine that classified matter no longer contains TFNI. (D) Only DOE-authorized persons may declassify matter marked as containing TFNI. (E) The DOE must review matter that potentially contains TFNI for public release. (vi) RD derivative classifiers must use approved classification guides, classification bulletins, or portion-marked source documents as the basis for classifying matter containing RD and FRD. (vii) Persons trained to make TFNI determinations must use approved TFNI guidelines, classification guides, classification bulletins, or portion-marked source documents as the basis for classifying or upgrade matter containing TFNI. (6) Marking matter containing RD, FRD, and TFNI. The front page of matter containing RD or FRD must have the highest classification level of the information on the top and bottom of the first page, the RD or FRD admonishment, the subject or title marking, and the classification authority block. Matter containing TFNI must include the TFNI identifier on each page unless the matter also contains RD or FRD, in which case the RD or FRD takes precedence. (i) Documents classified as RD or FRD must also include a Classification Authority Block with the RD derivative classifier's name and position, title, or unique identifier and the classification guide or source document (by title and (printed page 83362) date) used to classify the document. No declassification date or event may be placed on a document containing RD, FRD, or TFNI. If a document containing RD, FRD, or TFNI also contains NSI, ·N/A to RD/FRD/TFNI· (as appropriate) must be placed on the ·Declassify On:· line. (ii) Each interior page of matter containing RD or FRD must be clearly marked at the top and bottom with the overall classification level and category of the matter or the overall classification level and category of the page, whichever is preferred. The abbreviations ·RD· or ·FRD· may be used in conjunction with the matter classification (e.g., SECRET//RD, CONFIDENTIAL//FRD). Table 1 to Paragraph (e)(ii) RD and FRD Admonishment Markings Document containing Admonishment that must be included on the front page of the document RD ·RESTRICTED DATA This document contains RESTRICTED DATA as defined in the Atomic Energy Act of 1954. Unauthorized disclosure is subject to administrative and criminal sanctions.· FRD ·FORMERLY RESTRICTED DATA Unauthorized disclosure subject to administrative and criminal sanctions. Handle as Restricted Data in foreign dissemination. Section 144b, AEA 1954.·

One comment proposed eliminating third party assessment costs and relying only on self-certification to address the cost burdens. One comment noted that free market pricing and a short supply of C3PAOs combined with excessive waiting times may result in SMB attrition. Response: It is not within in scope of this rule to address how companies recover assessment costs. The CMMC rule makes no change to the cost allowability parameters described in FAR 31.201-2 Determining Allowability. Contractors are required to comply with all terms and conditions of DoD contracts, to include terms and conditions relating to cybersecurity protections and assessment requirements, as implemented by this rule. This holds true when a contract clause is flowed down to subcontractors. Several of the commenters' recommendations have potential benefit for the contractor and sub-contractor communities; however, they are beyond the scope of the rule. These recommendations included creation or expansion of: grants and assistance programs, financial support for small business, the DoD [Procurement] Toolbox, the DoD Office of Small Business Programs, contract incentives and free or reduced cost DoD cybersecurity services. DoD understands the burden on small business. Nonetheless, DoD must enforce CMMC requirements uniformly across the Defense Industrial Base for all contractors who process, store, or transmit CUI. The requirements necessary to protect a single document are the same as to protect many documents, therefore scaling by amount of CUI expected is not a viable approach. Solicitations for DoD contracts that will involve the processing, storing, or transmitting of FCI or CUI on any nonfederal system, regardless of the size or configuration of the nonfederal system, will specify the required CMMC Level (1, 2 or 3) and assessment type (self-assessment or independent third-party assessment). That requirement applies, regardless of the number of computers or components in a nonfederal information system. DoD's original implementation of security requirements for adequate safeguarding of CUI relied upon self-attestation by contractors. Since that time, the DoD Inspector General and DCMA found that contractors did not consistently implement mandated system security requirements for safeguarding CUI and recommended that DoD take steps to assess a contractor's ability to protect this information. All contractors or sub-contractors with access to CUI need to be capable of protecting that information to the standard

specified in 32 CFR part 2002. If a small business cannot comply with DFARS clause 252.204-7012 and NIST SP 800-171 R2, then that business should not be processing, storing, or transmitting CUI. DoD's programs, technological superiority, and best interests are not served if CUI is not consistently safeguarded by all who process, store, or transmit it. 28. Perceived Cost of CMMC Program Comment:

One comment requested the rule state that records in SPRS must be updated within six months of the rule's effective date or when the functionality is in place, whichever is longer. Two comments asked for mitigations for assessment delays that could impact the timeliness of certification. One comment asked for more information about assessment frequency guidelines, and one asked which date would be used to determine timing of CMMC Level 2 triennial assessments, where this date is maintained, and who is responsible for ensuring contractors meet all applicable security requirements. Response: To be eligible for a contract with a CMMC Level 1 self-assessment requirement, the OSA must perform a Level 1 self-assessment, input the result into SPRS, and submit an affirmation. The timeline for initiating and reporting a self-assessment is a business decision to be made by each contractor considering contract opportunities it wishes to pursue. Because the OSA can fully control timelines for completion of self-assessments and plan for changes within the assessment scope, and because CMMC certification assessments occur on a standard 3-year cycle, the DoD expects that companies will plan assessments well in advance of need. The required assessment frequency is every year for CMMC Level 1, and every 3 years for CMMC Levels 2 and 3, or when changes within the CMMC Assessment Scope invalidate the assessment. Certification dates for CMMC levels 2 and 3 are set to the date the certification assessment results are entered into SPRS for self-assessments or the date the Certificate of CMMC Status is (printed page 83134) entered into eMASS for third-party assessments. The triennial requirement renews on that date; there is no grace period. Each OSA's annual affirmation attests that they have implemented, and are maintaining their implementation of, the security requirements. 2. Supplier Risk Performance System and eMASS Comment:

A director (MGMT5) for 8 hours (\$190.52/hr × 8hrs = \$1,524) A staff IT specialist (IT4-SB) for 4.08 hours (\$86.24/hr × 4.08hrs = \$352) Phase 4: Closing out POA&Ms [51] (for CMMC Level 3 if necessary and allowed): \$1,869 A director (MGMT5) for 8 hours (\$190.52/hr × 8hrs = \$1,524) A staff IT specialist (IT4-SB) for 48 hours (\$86.24/hr × 48hrs = \$345) Reaffirmations: It is estimated that the costs to reaffirm a Level 3 certification assessment annually is \$1,876 (three-year cost is \$5,628, or \$1,876 × 3) A director (MGMT5) for 8 hours (\$190.52/hr × 8hrs = \$1,524) A staff IT specialist (IT4-SB) for 4.08 hours (\$86.24/hr × 4.08hrs = \$352) The Level 3 affirmations cost burden will be addressed as part of the 48 CFR part 204 CMMC Acquisition rule. Summary: The following is the annual small entities total cost summary for Level 3 certification assessments and affirmations over a ten-year period. Example calculation, Year 2 (reference per entity amounts shown): *(\$9,050 Certification per entity × 45 entities) + (\$1,876 Annual Affirmation per entity × 3 entities) = \$412,897, and \$121,500,000 Nonrecurring Engineering cost (\$2,700,000 per entity × 45 entities being certified), and (printed page 83189) \$23,520,000 Recurring Engineering cost (\$490,000 per entity × 45 entities being certified) + (\$490,000 per entity × 3 entities performing affirmations) \$145,432,897 Total Cost = Certification and Affirmation Cost (\$412,897) + Nonrecurring Engineering cost (\$121,500,000) + Recurring Engineering cost (\$23,520,000), or \$145,432,897. All Entities Summary The following is a summary of the cost to all entities regardless of size for Level 3 certification assessments and affirmations over a ten-year period: (printed page 83190) Government Costs Summary of Impact The following is a summary of the estimated Government costs calculated for a 20-year horizon in 2023 dollars at a 7 percent and 3 percent discount rate. The Government costs include conducting Level 3 certification assessments, uploading results into the CMMC instantiation of eMASS, and the CMMC PMO costs. Government Costs (All Levels)

The recordkeeping rule, however, exempts all foreign persons, except foreign persons who transport food in the United States. Therefore, the foreign exporter of the samples mentioned by the comment's is not required to establish and maintain records under this final rule. With respect to the comments assertion that the registration interim final rule exempts food carried in personal baggage for personal use, FDA notes that it is the prior notice interim final rule (part 1, subpart I) that exempts these products, not the registration interim final rule (part 1, subpart H). The registration interim final rule applies to all domestic and foreign facilities that manufacture, process, pack, or hold food that will be consumed in the United States, unless otherwise exempted. This includes facilities performing covered activities with respect to commercial samples if those

samples will be consumed in the United States. See response to comment 67 at 68 FR 58911 through 58912 (October 10, 2003). As detailed in the response to comment 22, this final rule does not distinguish between food consumed in the United States and food that is exported. (Comment 33) One comment indicates that the proposal is silent as to whether firms producing finished food products or food additives and ingredients intended solely for export must comply with the recordkeeping requirements. The comment argues that because this regulation applies to foods for consumption in the United States, producers of such products should be exempt from the recordkeeping requirements. (Response) Persons who manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States are subject to these regulations. If the food is intended solely for export, the person producing that food in the United States would still be subject to these regulations with respect to that food. 2. Farms (Comment 34) Several comments ask if foreign farms, including fish farms (aquaculture) fall under the regulation's farm exemption. (Response) Section 306 of the Bioterrorism Act specifically exempts farms from these regulations. The definition of a farm includes aquaculture facilities. In addition, foreign persons (except for foreign persons who transport food in the United States), including foreign farms, are excluded from all of these regulations. (Comment 35) One comment states that FDA has not clarified whether producers who ship live food animals to the United States will be required to keep records on their farm operations, as their products will be 'finished' in another country, may have been raised on more than one farm, and may not be considered as going directly to the consumer for consumption. The comment strongly urges the FDA not to require farmers shipping live animals to the United States to incur the additional cost, time, and work involved in maintaining records, beyond those which are currently being maintained for their operations, solely for the purpose of this regulation.

The health care sector has undergone a dramatic transformation over the last 24 years, and particularly in the past 10 years, spurred at least in part by the Department's implementation of HIPAA, the HITECH Act, and the Cures Act. The industry has shifted from one that generally relied upon a system of paper-based recordkeeping and siloed devices to one that depends on interconnected information systems to maintain and exchange patient records, conduct research, run health care provider facility management systems, and provide patient care. [166] This shift is largely the result of HIPAA's emphasis on the development and use of standards and the EHR incentive funds made available under the HITECH Act for health care providers. [167] Data from ASTP/ONC offer clear and convincing evidence of this shift. In 2008, before the enactment of the HITECH Act, less than 10 percent of non-Federal acute hospitals had implemented what was referred to at the time as a 'Basic EHR' (i.e., an electronic health record). [168] By 2015, six years after the enactment of the HITECH Act, almost 84 percent had adopted a Basic EHR while 96 percent had adopted a certified EHR. [169] The transformation was further enabled by the Cures Act, which encouraged the development of a trusted exchange framework for the nationwide exchange of health information and provided penalties for health care providers, health information exchanges and networks, and developers of certified health IT that engage in information blocking. [170] In 2014, 41 percent of such hospitals routinely had electronic access to clinical information from outside providers or sources when treating a patient. [171] By 2023, 70 percent of non-Federal acute care hospitals engaged in all domains of interoperable exchange routinely or sometimes, a significant leap forward. [172] In 2017, only 38 percent of hospitals enabled patients to access their health information using an application and in 2018, 57 percent enabled patient access to their clinical notes in their patient portal; by 2021, 70 percent of hospitals enabled patients to access their health information using an application and 82 percent enabled patients to view their clinical notes in their patient portal. [173] And just a year later, the percentage of hospitals that supported patient access through applications increased to 86 percent. [174] Based on this data, it is clear that HIPAA, coupled with the HITECH Act and the Cures Act, has successfully encouraged the development of a nationwide electronic health information system. Not only is PHI increasingly maintained and transmitted electronically, but treatment is also increasingly provided electronically. The coronavirus disease 2019 (COVID-19) pandemic led to a dramatic increase in the use of telemedicine. [175] According (printed page 911) to ONC data, only 15 percent of office-based physicians used any form of telemedicine in 2018-19. In 2021, telemedicine usage increased to 87 percent. [176]

From the NIST SP 800-172 Rev 3 Final Public Draft: nonfederal system A system that does not meet the criteria for a federal system. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 o n behalf of (an agency) 3026

(E) Agency materials underlying the President's budget decisions as described in OMB Circular No. A-11. This includes planning, programming, and budgetary information that is involved in the defense planning and resource allocation process and outyear discretionary data. (ii) Attorney client privilege. This privilege protects confidential communications between an attorney and a client relating to legal matters for which the client has sought professional advice. The information the client supplies to the attorney and the advice the attorney gives to the client in return are protected under this privilege. Courts extend the confidential element of this privilege to lower echelon Government employees because it is recognized when the Government is seeking legal advice it usually involves more than one client and one attorney. This privilege cannot be used if confidentiality is compromised. (iii) Attorney work product privilege. This privilege protects documents prepared by an attorney or at an attorney's direction in reasonable anticipation of litigation. Unlike the deliberative process privilege, under the attorney work product privilege all of the information can be withheld, including the facts. Similarly, this privilege has no time limit. This privilege can be used after the litigation is complete. (iv) Government trade secret privilege. This privilege protects trade secrets or other confidential research, development, or commercial information owned by the Government, where premature release is likely to affect the Government's negotiating position or other commercial interest. (v) Aircraft accident witness statements privilege. This privilege protects witness statements generated during military aircraft accident investigations. (vi) Presidential communications privilege. This privilege protects communications among the President and his advisors created within an agency to assist the President in the exercise of his nondelegable constitutional duties. (f) Exemption 6. Pursuant to 5 U.S.C. 552(b)(6), information in personnel and medical files, as well as similar in other files, that if disclosed to a requester other than the person whom the information is about, would result in a clearly unwarranted invasion of personal privacy is exempt from disclosure. If the information qualifies as Exemption 6 information, there is no discretion in its release. (1) When applying this exemption, an agency must balance the public interest in disclosure and the individual's privacy interest. When there is no public interest in the requested (printed page 71856) information, the information can be withheld even if there is only a negligible privacy interest. The public interest to be considered when applying this exemption is whether the information sheds light on the operations or activities of the Federal government. The requester has the burden to show there is a public interest in disclosure.

Note that ISCM Process Step is listed as a view. While ISCM Process Step is a view in many respects, the ISCM Process Step view has a special role in ISCMA as the foundation of the ISCM process, and modifying individual ISCM process steps or deleting the ISCM Process Step view undermines the integrity of the ISCMaX application.

(iii) The contractor will not disclose information protected by this statutory provision to anyone except personnel who require access to the information in connection with the contract. (3) It is the responsibility of the foreign entity that awards the contract to incorporate requirements for the protection and marking of RESTRICTED or In Confidence information in the contract. The contractor will advise the CSA if requirements were not provided by the foreign entity. (n) Marking U.S. documents containing FGI. (1) U.S. documents containing FGI must be marked on the front, THIS DOCUMENT CONTAINS (indicate country of origin) INFORMATION. In addition, the portions must be marked to identify both the country and classification level, (e.g., (UK-C), (GE-C)). The Derived From line will identify U.S. as well as foreign classification sources. (2) If the identity of the foreign government must be concealed, the front of the document will be marked THIS DOCUMENT CONTAINS FOREIGN GOVERNMENT INFORMATION; paragraphs will be marked FGI, together with the classification level (e.g., (FGI-C)); and the Derived From line will indicate FGI in addition to any U.S. source. The identity of the foreign government will be maintained with the record copy of the document. (3) A U.S. document that contains FGI will not be downgraded below the highest level of FGI contained in the document or be declassified without the written approval of the foreign government that originated the information. Recommendations concerning downgrading or declassification will be submitted to the GCA or foreign government contracting authority, as applicable. (o) Marking documents prepared for foreign governments. Documents prepared for foreign governments that contain U.S. classified information and FGI will be marked as prescribed by the foreign government. In addition, they will be marked on the front, THIS DOCUMENT CONTAINS UNITED STATES CLASSIFIED INFORMATION. Portions will be marked to identify the U.S. classified information. (p) Marking requirements for transfers of defense articles to Australia (AUS) or the United Kingdom (UK). Marking requirements for transfers of defense articles to AUS or the UK

without a license or other written authorization are pursuant to § 117.19(i). (q) Commingling of RD and FRD. Commingling of RD, FRD, and TFNI with national security information (NSI) in the same document should be avoided to the greatest degree possible. When mixing this information cannot be avoided, the marking requirements in 10 CFR part 1045, section 140(f) and declassification requirements of 10 CFR part 1045, section 155 apply. § 117.15 Safeguarding Classified Information. (a) General safeguarding.

, which are the definitive sources for these definitions. DoDI 8582.01, published on December 9, 2019, points to FAR clause 52.204-21 and DFARS clause 252.204-7012, both of which preceded it, to address the safeguarding requirements for FCI and CUI. CMMC builds from those requirements by requiring that defense contractors and subcontractors provide assurance, either with Self-Assessments, Third-Party Assessments, or Level 3 Assessments, as required, that they have implemented the required information protection requirements. 8. Small Business/Entities a. Assistance/Support for Small Business Comment: Several commenters suggested that in order to successfully implement cybersecurity requirements, contractors require support from the Department. One commenter suggested DoD should perform an analysis of each requirement and ensure that necessary support structures are in place and fully functioning prior to implementing this rule, and that access to tech support/solutions should be provided. Multiple commenters suggested that more support and guidance is needed for small businesses trying to comply with CMMC. One commenter suggested that DoD should relax affiliation rules (in conjunction with the Small Business Association (SBA)) to allow small companies to work together to meet CMMC requirements while spreading the cost over a larger base and expand mentor-protégé agreements for larger businesses to help smaller companies with CMMC appraisals. One commenter expressed concern for non-traditional, innovative companies that are coming in through the Small Business Innovation Research (SBIR) and Small Business Technology Transfer (STTR) process and asked what DoD is doing to help them become compliant. Another noted that if CMMC Level 1 will be the minimum requirement for SBIRs and STTRs, regardless of whether they include FCI, it may significantly limit the number of universities that can partner with small businesses under these awards. Response: DoD's Office of Small Business and Technology Partnerships (OSBTP) is working to provide SBIR/STTR programs with support for CMMC implementation through the use of Technical and Business Assistance. The SBA's affiliation rules are codified at 13 CFR 121.103, available at <https://www.ecfr.gov/current/title-13/chapter-I/part-121>. Any change to the SBA's affiliation rules is outside the scope of this rulemaking. The CMMC Program is designed to increase assurance that defense contractors do in fact, comply with information protection requirements to adequately protect FCI and CUI. Additional information to assist contractors regarding DoD's current information security protection requirements may be found in Frequently Asked Questions (FAQs) Regarding the Implementation of DFARS subpart 204.73, published at <https://DoDprocurementtoolbox.com/>. b. Impact of Cost Comment:

The phased implementation plan for CMMC described in § 170.3(e) is intended to address ramp-up issues, provide time to train the necessary number of assessors, and allow companies the time needed to understand and implement CMMC requirements. The rule has been updated to add an additional six months to the Phase 1 timeline. Phase 2 will start one calendar year after the start of Phase 1. 5. Scoping. Commenters expressed concerns about how External Service Providers (ESP) and SPA and SPD are handled with regard to certification. Another commenter expressed concern about the lack of FedRAMP Moderate certified capabilities in the market as well as requesting clarification on the definition of 'Specialized Assets', specifically regarding equipment in manufacturing that may not fall under the conventional categories of IoT, IIoT, and OT. Another commenter expressed concerns about how Contractor Risk Managed Assets (CRMA) are handled, along with concerns about available FedRAMP certified capabilities. Other comments identified concerns with the responsibility of a company that adopts an ESP and their adherence to security requirements, and the lack of time given in Phase 2 of the CMMC roll-out to garner certification. A question was also asked regarding the Department's assumptions on the rigor a Certifying Officer [Affirming Official in the rule] would require before signing an attestation and the methodology used to determine the resultant actions that must be taken. Another raised a concern regarding how sub-environments are handled as well as end-to-end encryption in handling CUI. Another expressed concern regarding the marking of data as CUI and the potential for overmarking. Some commenters made suggestions that all CUI be held in a special appendix for contracts and only be allowed to be accessed at the prime's facility or through a government hosted secure portal. A commenter also suggested that small businesses should not be made to meet the CMMC Level 3 requirements. Another commenter raised questions about the alternatives that the Department considered in developing the CMMC Program. Another suggestion was

to provide uniform web-based training on cybersecurity and that the definition of CUI was unclear, and CUI should stay under the control of the Federal Government and be maintained in a government owned secure portal. A suggestion was also made that DoD establish a Cyber Protection Program that monitors DIB companies and provides real time health reports on the DIB and dynamic intelligence security alerts and recommended actions. A suggestion that NIST establish a special standard for micro-organizations was also provided. Commenters also suggested that the rule was too stringent, and CUI was not marked well or flowed down to subcontractors appropriately. DoD Response:

- Protected execution: Lets applications run in isolated environments so that no unauthorized software on the platform can observe or tamper with the operational information. Each of these isolated environments executes with the use of dedicated resources managed by the platform.
- Sealed storage: Provides the ability to encrypt and store keys, data, and other sensitive information within the hardware. This can only be decrypted by the same environment that encrypted it.
- Attestation: Enables a system to provide assurance that the protected environment has been correctly invoked and to take a measurement of the software running in the protected space. This is achieved by the attestation process defined in Section 3.1. The information exchanged during this process is known as the attestation identity key credential and is used to establish mutual trust between parties.
- Protected launch: Provides the controlled launch and registration of critical system software components in a protected execution environment.

Port	Purpose	Direction
5432	PostgreSQL Database	Internal
8443	Host Verification Service (HVS)	Inbound/outbound
8444	Authentication and Authorization Service (AAS)	Inbound/outbound
8445	Certificate Management Service (CMS)	Inbound/outbound
5000	Workload Service (WLS)	Inbound/outbound
9443	Key Management Service (KMS)	Inbound/outbound
1443	Trust Agent (TA)	Inbound/outbound
19082	Integration Hub (HUB)	Inbound/outbound
19445	Authentication and Authorization Service	Inbound/outbound

Allowing Plans of Action & Milestones (POA&M) under limited circumstances to achieve conditional certification. As a result of the alignment of the revised CMMC Program to NIST guidelines, the Department's requirements will continue to evolve as changes are made to the underlying NIST SP 800-171 R2, NIST SP 800-171A Jun2018, NIST SP 800-172 Feb2021, and NIST SP 800-172A Mar2022 requirements. CMMC Assessment Criteria CMMC requires that defense contractors and subcontractors entrusted with FCI and CUI implement cybersecurity standards at progressively more secure levels, depending on the type and sensitivity of the information. Level 1 Self-Assessment An annual Level 1 self-assessment and annual affirmation asserts that an OSA has implemented all the basic safeguarding requirements to protect FCI as set forth in § 170.14(c)(2). An OSA can choose to perform the annual self-assessment internally or engage a third-party to assist with evaluating its Level 1 compliance. Use of a third party to assist with the assessment process is still considered a self-assessment and results in a CMMC Status of Final Level 1 (Self). An OSA achieve the CMMC Status of Level 1 (Self) for an entire enterprise network or for a particular enclave(s), depending upon where the FCI is or will be processed, stored, or transmitted. Level 2 Self-Assessment A Level 2 self-assessment and annual affirmation attests that an OSA has implemented all the security requirements to protect CUI as specified in § 170.14(c)(3). Level 2 Certification Assessment A Level 2 certification assessment, conducted by a C3PAO, verifies that an OSC is conforming to the security requirements to protect CUI as specified in § 170.14(c)(3). Each OSC information system that will process, store, or transmit CUI in the execution of the contract is subject to the corresponding CMMC Status requirements set forth in the contract. Level 3 Certification Assessment Achievement of the CMMC Status of Final Level 2 (C3PAO) for information systems within the Level 3 CMMC Assessment Scope is a prerequisite for initiating a Level 3 certification assessment. A Level 3 certification assessment, conducted by DCMA Defense Industrial Base Cybersecurity Assessment Center (DIBCAC), verifies that an OSC has implemented the CMMC Level 3 security requirements to protect CUI as specified in § 170.14(c)(4). A Level 3 certification assessment must be conducted for each OSC information system that will be used in the execution of the contract that will process, store, or transmit CUI. Impact and Cost Analysis of the Revised CMMC Program Summary of Impact Public comment feedback on the initial CMMC Program indicated that cost estimates were too low. The revised (printed page 83176) CMMC Program cost estimates account for that feedback with the following improvements: Allowance for outsourced IT services

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of

each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 117 [Docket ID: DOD-2011-OS-0063] RIN 0790-AI71 AGENCY: Department of Defense (DoD). ACTION: Interim final rule. SUMMARY: This DoD interim final rule (rule) assigns responsibilities and establishes requirements related to the National Industrial Security Program (NISP) to ensure maximum uniformity and effectiveness for both DoD and non-DoD Components, as defined in this rule, for which the Department serves as the Cognizant Security Agency (CSA) and provides industrial security services in accordance with Executive Order (EO) 12829, National Industrial Security Program. The rule provides guidance on the procedures used to ensure classified information will be properly safeguarded if a contractor has reported foreign ownership, control or (printed page 19468) influence (FOCI) information which DoD must evaluate, mitigate, or negate as appropriate. The rule also provides guidance for the evaluation, mitigation, and/or negation of FOCI information reported by a company, as defined in the rule, which is in process for a facility security clearance (FCL). DATES: Effective Date: This rule is effective April 9, 2014. Comments must be received by June 9, 2014. ADDRESSES: You may submit comments, identified by 32 CFR part 117 , Docket No. DoD-2011-OS-0063 or Regulatory Information Number (RIN) 0790-AI71 by any of the following methods: Federal Rulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. Mail: Federal Docket Management System Office, 4800 Mark Center Drive, 2nd floor, East Tower, Suite 02G09, Alexandria, VA 22350-3100. Instructions: All submissions received must include the agency name and docket number or RIN for this Federal Register document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing on the Internet at <http://www.regulations.gov> as they are received without change, including any personal identifiers or contact information. FOR FURTHER INFORMATION CONTACT: Valerie Heil, (703) 604-1112. SUPPLEMENTARY INFORMATION: Executive Summary The purpose of this part 117, subpart C is to set forth industrial security procedures and practices related to FOCI for the Components to ensure maximum uniformity and effectiveness in the DoD implementation of E.O. 12829 .

FDA outbreak investigation personnel estimate that a full outbreak investigation lasts at least 3 to 5 weeks, with a most likely duration of 2 to 6 months, and a maximum duration of 10 months (Ref. 2). The numbers of outbreak investigations and investigative visits come from internal interviews with investigation personnel and from other data maintained by FDA (Ref. 2). The annual numbers of outbreaks investigated, investigative visits, and investigations that are prematurely terminated for reasons of poor records quality are reported in table 8 of this document. A traceback is defined to be prematurely terminated for records quality reasons if investigators noted in summarizing information that data quality impeded the investigation which ended before investigators were able to determine the specific cause of the outbreak. We used the simple averages over the 4 years reported in the table to estimate the annual numbers of outbreaks investigated, the annual numbers of investigative visits per outbreak investigated, and the annual rates of investigations prematurely terminated for reasons of poor records quality. We characterized the uncertainty of these estimates as normal distributions with means and standard deviations taken from the data on annual numbers of outbreaks and investigative visits per outbreak. For the annual rate of prematurely terminated investigations, we characterized the uncertainty with a beta pert distribution using the average, low and high values reported in the table 8 of this document. Table 8. Outbreak Investigation Data

Year	Number of Outbreaks Investigated	Number of Investigative Visits per outbreak	Rate of records quality related premature terminations
2000	9	12	0.11
2001	9	11	0.33
2002	18	7	0.06
2003	17	6	0.00

The recordkeeping requirements of this final rule will improve the quality of records established and maintained by persons that manufacture, process, pack, transport, distribute, receive, hold, or import food. For options that provide comprehensive coverage of all food facilities, we estimate that the number of investigations prematurely terminated because of poor records would fall to zero. For options that provide less than comprehensive coverage, the reduction in premature terminations is reduced in proportion to the coverage.

Back to Citation 1000. · See ·Table of Small Business Size Standards,· U.S. Small Business Administration (Mar. 17, 2023), https://www.sba.gov/sites/sbagov/files/2023-06/2023-06-Table%20of%20Size%20Standards_Effective%20March%2017%2C%202023%20%282%29.pdf . Back to Citation 1001. Id. Back to Citation 1002. ·Market Share and Enrollment of Largest Three

Insurers·Large Group Market,· Kaiser Family Foundation (2019), <https://www.kff.org/other/state-indicator/market-share-and-enrollment-of-largest-three-insurers-large-group-market/?currentTimeframe=0&sortModel=%7B%22colId%22:%22Location%22,%22sort%22:%22asc%22%7D> .

Back to Citation 1003. · See ·Table of Small Business Size Standards,· *supra* note 1000.

Back to Citation 1004. ·This figure is rounded and represents annualized costs discounted at a 2 percent rate. The actual figure is \$2,251,258,305. Back to Citation 1005. ·SUSB 2017 reports average revenue per firm by employment size. The size categories begin with less than 5 employees followed by 5 to 10 employees, and so on, with the largest categories representing firms with 2,500 to 4,999 employees and 5,000 or more employees). ·2017 [Statistics of U.S. Businesses] Annual Data Tables by Establishment Industry,· (May 2021), <https://www.census.gov/data/tables/2017/econ/susb/2017-susb-annual.html> . We inflated these revenues to 2021 dollars using the GDP deflator to estimate average revenues in each employment class in 2021 because that is the latest year for which data is reported. See ·2021 [Statistics of U.S. Businesses] SUSB Annual Data Tables by Establishment Industry,· *supra* note 947. We then concluded that more than 5 percent of the firms whose revenues fall below the SBA thresholds (see table 4) belong to the ·fewer than 5 employees· category and operate a single establishment. Back to Citation 1006. ·\$6,133 is 3 percent of \$204,433. Back to Citation 1007. ··Average Small Business Revenue: What To Know,· *Fora Financial* (Jan. 11, 2023), <https://www.forafinancial.com/blog/small-business/average-small-business-revenue/> . Back to Citation 1008. 42 U.S.C. 1320d-2(d) . Back to Citation 1009. · See 68 FR 8334 , 8341 (Feb. 20, 2003). Back to Citation 1010. · See ·Fact Sheet: Biden-Harris Administration Bolsters Protections for Americans' Access to Healthcare Through Strengthening Cybersecurity,· *supra* note 306. See also table 4 above, SBA size threshold for hospitals. Back to Citation 1011. · See ·2021 [Statistics of U.S. Businesses] SUSB Annual Data Tables by Establishment Industry,· *supra* note 947 (count of hospitals). Back to Citation 1012. ·The Indian Health Service funds a ·network of over 600 hospitals, clinics, and health stations on or near Indian reservations in service areas that are rural, isolated, and underserved.· ·Justification of Estimates for Appropriations Committees, Fiscal Year 2025· Indian Health Service, U.S. Department of Health and Human Services, p. CJ-39 (Mar. 5, 2024). Back to Citation 1013. See *id.* at p. CJ-63-75.

Section 170.5 addresses that the CMMC Program does not alter the requirements imposed on contractors and subcontractors in FAR clause 52.204-21, DFARS clause 252.204-7012, or any other applicable safeguarding of information requirement. The CMMC Program verifies implementation of security requirements in FAR clause 52.204-21, NIST SP 800-171 R2, and selected security requirements in NIST SP 800-172 Feb2021, as applicable. Section 170.6·CMMC PMO Section 170.6 addresses the CMMC Program Management Office (PMO) functions that are performed within the Department of Defense Chief Information Officer (DoD CIO). Section 170.7·DCMA DIBCAC Section 170.7 addresses how DCMA DIBCAC will support the CMMC Program by conducting CMMC Level 2 certification assessments of the Accreditation Body and C3PAOs; conducting CMMC Level 3 certification assessments for OSCs; and recording results, issuing certificates, tracking appeals, and retaining records as required.

Section 170.8·Accreditation Body Section 170.8 addresses the roles and responsibilities of the Accreditation Body, as well as requirements that the Accreditation Body must meet. The Accreditation Body must be US-based and be and remain a member in good standing with the Inter-American Accreditation Cooperation (IAAC) and become an International Laboratory Accreditation Cooperation (ILAC) Mutual Recognition Arrangement (MRA) signatory, with a signatory status scope of ISO/IEC 17020:2012(E) and be compliant with ISO/IEC 17011:2017(E) [20] . There is only one Accreditation Body for the DoD CMMC Program at any given time, and its primary mission is to authorize and accredit the C3PAOs. The Accreditation Body authorizes and accredits C3PAOs in accordance with the requirements in section 170.8(b). The Accreditation Body also oversees the CAICO to ensure compliance with ISO/IEC 17024:2012(E) [21] and to ensure all training products, instruction, and testing materials are of high quality. Section 170.8 addresses specific requirements for the Accreditation Body with regards to national security background checks, foreign ownership, reporting, information protection, and appeals. The Accreditation Body will also develop policies for Conflict of Interest (Col), Code of Professional Conduct (CoPC), and Ethics that comply with all ISO/IEC 17011:2017(E) and DoD requirements. These policies will apply to the Accreditation Body as well as to all other individuals, entities, and groups within the CMMC Ecosystem. The information systems used by the Accreditation Body to process CMMC information have to meet all of the security requirements for CMMC Level 2 and will be assessed by DCMA's Defense Industrial Base Cybersecurity Assessment Center (DIBCAC). Section 170.9·CMMC Third-Party Assessment Organizations

(C3PAOs)

Long distance companies entering the market initially relied on a five or six digit Personal Identification Number (PIN) to provide each customer access to their networks. Codes were easy to break and companies using them were very vulnerable. Long distance companies lengthened their codes to seven, nine and finally, to the 14-digit authentication codes currently used. Even 14 digit codes are vulnerable since the first ten digits are usually the home phone number and the last four digits are the PIN.

(Comment 8) One comment requests that source labeling, including country-of-origin labeling, be required as a component of an effective traceback program in the event of a food emergency. The comment states that some industries have already developed technologies such as barcodes, stamps, stickers, or tags to identify the source of produce as well as software to assist in more accurate traceback to the grower/packer level. (Response) FDA does not agree. At this time, FDA does not believe this information is necessary to enable a traceback. FDA believes the requirements of the final regulations for the establishment and maintenance of records to identify the immediate previous sources and immediate subsequent recipients of food in order to address credible threats of serious (printed page 71568) adverse health consequences or death to humans or animals are sufficient. (Comment 9) Some comments ask that the agency generate more publicity on the regulations and provide the industry with educational materials and training. One comment states that because food wholesale distributors have no significant contact with FDA personnel and procedures, they have a limited understanding of the requirements. One comment asks that the agency help promote and educate the industry abroad on the recordkeeping regulations. Another comment asks that FDA provide materials in other languages. One comment asks that the agency develop a strong communications program to disseminate the new regulations once they become final because the fresh produce industry and its transportation partners are highly diverse and fragmented. The comment states that independent truckers in particular need to be made aware of the regulations because the fresh produce industry in the United States relies heavily on independent truckers to move fresh fruits and vegetables to market quickly. (Response) FDA conducted extensive outreach on the proposed recordkeeping rule, including having relevant FDA staff attend 6 international meetings and more than 100 domestic meetings to ensure that affected parties were aware of the Bioterrorism Act requirements. On May 7, 2003, FDA held a public meeting (via satellite downlink) to discuss the recordkeeping and administrative detention proposed rules. See 68 FR 16998 (April 8, 2003) or <http://www.cfsan.fda.gov/~dms/~fsbttraz.html>. Nearly 1,000 participants in North and South America and the Caribbean viewed that live broadcast. The meeting was later rebroadcast to Europe, Asia, Africa, and the Pacific (areas in different time zones). FDA has also provided transcripts of the broadcast in English, French, and Spanish (the three official World Trade Organization languages) on the agency's Web site. In addition to this outreach to the affected industry, FDA has conducted outreach on the proposed rule to States.

(1) Obtain and maintain certification from the CAICO in accordance with the requirements set forth in § 170.10. Certification is valid for 3 years from the date of issuance. (2) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics as set forth in § 170.8(b)(17). (3) Complete a Tier 3 background investigation resulting in a determination of national security eligibility. This Tier 3 background investigation will not result in a security clearance and is not being executed for the purpose of government employment. The Tier 3 background investigation is initiated using the Standard Form (SF) 86 (www.gsa.gov/reference/forms/questionnaire-for-national-security-positions). These positions are designated as non-critical sensitive with a risk designation of 'Moderate Risk' in accordance with 5 CFR 1400.201(b) and (d) and the investigative requirements of 5 CFR 731.106(c)(2). (4) Meet the equivalent of a favorably adjudicated Tier 3 background investigation when not eligible to obtain a Tier 3 background investigation. DoD will determine the Tier 3 background investigation equivalence for use with the CMMC Program only. (5) Provide all documentation and records in English. (6) Not share any information about an OSC obtained during CMMC pre-assessment and assessment activities with any person not involved with that specific assessment, except as otherwise required by law. Subpart D-Key Elements of the CMMC Program § 170.14 CMMC Model. (a) Overview. The CMMC Model incorporates the security requirements from: (1) 48 CFR 52.204-21, Basic Safeguarding of Covered Contractor Information Systems; (2) NIST SP 800-171 R2, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations (incorporated by reference, see § 170.2); and (3) Selected security requirements from NIST SP 800-172 Feb2021,

Enhanced Security Requirements for Protecting Controlled Unclassified Information: A Supplement to NIST Special Publication 800-171 (incorporated by reference, see § 170.2). (b) CMMC domains. The CMMC Model consists of domains that map to the Security Requirement Families defined in NIST SP 800-171 R2 (incorporated by reference, see § 170.2). (c) CMMC level requirements. CMMC Levels 1-3 utilize the safeguarding requirements and security requirements specified in 48 CFR 52.204-21 (for Level 1), NIST SP 800-171 R2 (incorporated by reference, see § 170.2) (for Level 2), and selected security requirements from NIST SP 800-172 Feb2021 (incorporated by reference, see § 170.2) (for Level 3). This paragraph discusses the numbering scheme and the security requirements for each level. (1) Numbering. Each security requirement has an identification number in the format DD.L#-REQ where: (i) DD is the two-letter domain abbreviation; (ii) L# is the CMMC level number; and (iii) REQ is the 48 CFR 52.204-21 paragraph number, NIST SP 800-171 R2 requirement number, or NIST SP 800-172 Feb2021 requirement number. (2)

According to Report_ Authentication Diary Study, EXECUTIVE SUMMARY: EXECUTIVE SUMMARY The purpose of authentication is to ensure that only authorized individuals have access to a particular resource or physical area. To authenticate and prove their 'right to access,' a person must essentially prove that they are who they claim to be (i.e., an authorized individual) by presenting elements such as ID badges, fingerprints, personal identification numbers (PINs) or - very often - a username and password. For users of information technology, authentication is an inescapable fact of daily life - and it affects them in ways that are still poorly understood. In order to better understand users' authentication-related perceptions and behaviors, we conducted a two-part study with 25 NIST employees. In the first part of the study, we instructed our participants to record all the authentication events they encountered over a 24-hour period (in the workplace and, if they so chose, at home) using forms we provided. The second part of the study consisted of individual follow-up interviews regarding participants' experiences with authentication. Our study was designed to answer the following questions: - Where does authentication fit into the daily activities people carry out? - What characteristics of authentication may interfere with the primary activity that authentication is supposed to enable? What are the friction points? - How do people add up the cumulative costs of authenticating multiple times each day, and how do they balance them against their own perceived security needs? - How do people perceive the costs of performing security tasks (particularly authentication tasks) in comparison with the benefits of performing those tasks? We found that our participants were confused about what 'authentication' actually meant. For example, one participant erroneously recorded unlocking his car with his remote key fob as an authentication event.

3.4.2 Intel QuickAssist Technology (QAT) with Intel Key Protection Technology (KPT) Intel QuickAssist Technology (QAT) is a high-performance hardware accelerator for performing cryptographic, security, and compression operations.

(B) From subsections (d) and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because there is no necessity for such publication since the system of records will be exempt from the underlying duties to provide notification about and access to information in the system and to make amendments and corrections to the information in the system. (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NSA will, nevertheless, continue to publish such a notice in broad generic terms, as is its current practice. (16) System identifier and name.

GNSA 20, NSA Police Operational Files. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(16)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions.

(Comment 137) One comment expressed concern that, under the proposed regulation, persons who do not know if perishable food is intended for processing into nonperishable food would have to assume it is and maintain records for 2 years. A few comments state that persons, such as distributors, carriers, farms or orchards, roadside stands, and small collection centers generally have no way of knowing whether a perishable food will be processed into a nonperishable food by other parties. A few comments ask FDA to clarify that companies selling perishables can rely on the applicability of the 1-year records retention period unless they have actual knowledge at the time of sale that the perishables will be used for processing into nonperishable foods. (Response) Section 1.360 of the final rule specifies retention periods based on the type of food being received or released, not on the end use of the food being delivered. (Comment 138) One comment states that the proposed requirements are more burdensome than is necessary to enable food producers to respond quickly and appropriately to a food safety emergency. The comment further states that the proposal does not take into account the sheer volume that retail grocery stores deal with on a daily basis. According to the comment, the average retail grocery store currently is capable of retaining such records for only approximately 1 week. The comment concludes that the requirement to maintain records for 2 years is completely unworkable and will not serve in the interest of public health in times of crisis. (Response) FDA has revised the record retention periods for nontransporters to 6, 12, and 24 months as discussed in response to comment number 129. FDA believes that these timeframes are within the period Congress believed appropriate because the Bioterrorism Act gives FDA authority to require records to be retained for up to 2 years. Moreover, Congress did not exempt retailers (e.g., retail grocery stores) from the recordkeeping requirements, as they did in section 305 of the Bioterrorism Act (registration of food facilities). FDA believes that the benefit to FDA and consumers in conducting an efficient and rapid traceback in a public health emergency justifies the burden to industry.

CMMC Program rule. Any discussion of exemptions for foreign businesses are outside the scope of the 32 CFR part 170 CMMC Program rule and may be addressed through government-to-government international arrangements or agreements. The Discussion of Public Comments and Resulting Changes section in the preamble of the final rule addresses all public comments received during the mandatory 60-day public comment period for the proposed rule and supporting documents. Response to Comments From Chief Counsel for Advocacy of the SBA On December 26, 2023, the Department of Defense (DoD) published a proposed rule entitled Cybersecurity Maturity Model Certification (CMMC) Program, 88 CFR 89058. This proposed rule intends to create a mechanism by which the DoD can certify that contractors and subcontractors are in compliance with the stated cybersecurity guidelines. The SBA Office of Advocacy (SBA or Advocacy) submitted the following comments and concerns on the proposed rule in a letter addressed to the DoD CIO within the public comment period for the proposed 32 CFR part 170 CMMC Program rule. ·Advocacy is principally concerned with the ability for small businesses to meet and comply with the standards and timelines set out in the CMMC Program without further clarification and guidance documents from the DoD. The current rule does not provide clear guidance on the process to create enclaves, which would allow more small business subcontractors to participate in DoD contracts without meeting the full requirements necessary for the prime contractor. Advocacy seeks clarification on the role of Third-Party Assessment Organizations (C3PAO) and the indemnification a C3PAO has if a contractor or subcontractor is out of compliance. ·Advocacy concerns also include the process of how and if more C3PAOs can be certified by the DoD to review the numerous contracts that will be subject to certifications. Advocacy urges the DoD to provide clarification about the enforcement mechanisms for breaches of cybersecurity. ·Lastly, Advocacy reminds the DoD that this rule will impose a high cost of compliance on small businesses and any means to reduce the burden on small businesses will increase the participation of these impacted businesses. ·The proposed rule would give contractual effect to NIST SP 800-171 and 172, requiring companies to meet the three levels of compliance if the contracts involve FCI or CUI. CMMC

attempts to redesign previous iterations of cybersecurity models with a more streamlined process. This proposal would simplify previous systems to create a more streamlined certification system. This rule differs from previous iterations by allowing for businesses to create enclaves within their business models, allowing the business to implement the CMMC standards while not drastically changing every aspect of their business process. · SBA Comment 1:

Middle and high estimates of the value of a health day are derived from estimates reported in the literature of the value of a statistical life. A value of a statistical life of \$6.5 million is consistent with the findings of a literature survey of the premium for risk observed in labor markets, reported by Aldy and Viscusi (Ref. 15). We derive middle and high estimates of the value of a health day by annualizing the value of a statistical life of \$6.5 million over 35 years at discount rates of 3 percent and 7 percent. These computations yield middle and high estimates for the value of an additional year of life of about \$300,000 and \$500,000. We estimated the range in values of a health day by dividing each of the estimates of the value of an additional year of health by 365, which yields estimates of \$274, \$822, and \$1,370. To calculate the indirect costs of mild, moderate, and severe cases of the illnesses, we multiplied the low, middle, and high estimates of the value of a health day by the QALD estimated for each illness and severity. Consistent with OMB's guidance on the use of multiple values for a statistical life, we used values of \$5.0 million and \$6.5 million to compute the value of a death from an illness. The estimated range of the average cost of an illness resulting from outbreaks monitored by FDA from 2000 to 2003 is reported in the following table. The averages reported in table 7 of this document are weighted by the total number of reported and unreported illnesses from each agent, as well as the assumed distributions of mild, moderate, and severe cases, including deaths, from those illnesses. As explained earlier, we valued statistical deaths at \$5 million and \$6.5 million, and the low, medium, and high estimates assume values of a healthy year of \$100,000, \$300,000, and \$500,000. Table 7. Average Cost of an Illness Across Outbreaks

	Low	Medium	High	VSL = \$5 million	\$6,136	\$13,209	\$20,282	VSL = \$6.5 million
million	\$6,810	\$13,883	\$20,955	6.	The Stages of an Outbreak Investigation			

binary OCSP - ## Key Usage : critical Key Encipherment ## Certificate Policies : id_fpci_common_hardware ## Subject Alternative Name ## : email:test.cardholder4@mail.example.com ## D.4.4.7 Test PIV Card 4: Retired Key Management Certificate C Serial Number : 407 (0x197) Signature Algorithm : sha1WithRSAEncryption Issuer : CN=Expired Test RSA 2048-bit CA for Test PIV Cards, ou=Test CA, o=Test Certificates 2010, c=US Validity : Not Before: Mar 2 11:17:23 2007 GMT, Not After: Mar 2 11:17:23 2010 GMT Subject : CN=Test E.

The rule will apply to all small entities that will be awarded cost-reimbursement, time-and-material, or labor-hour contracts. However, the rule requires negligible additional effort by contractors, including small entities, because it simply clarifies the identification and use of payment information elements in payment requests. According to data from the Federal Procurement Data System for fiscal years 2020 through 2022, approximately 6,800 cost-reimbursement, time-and-material, and labor-hour contracts (0.01% percent of all awards) are awarded to approximately 1,100 small businesses (3 percent of all awardees) each year. This rule also applies to contracts that use multiple accounting classifications or that involve progress payments for multiple production lots. DoD cannot accurately quantify the number of contracts subject to the multiple-lot progress payments clause, but such contracts are likely few in number. The rule does not contain any new reporting, recordkeeping, or other compliance requirements for small entities. There are no known, significant, alternative approaches to the rule that would meet the objectives of the rule. VIII. Paperwork Reduction Act The Paperwork Reduction Act (44 U.S.C. chapter 35) applies to this rule regarding new DFARS clause 252.232-7018, Progress Payments Multiple Lots. However, these changes to the DFARS do not impose additional information collection requirements to the paperwork burden previously approved under Office of Management and Budget (OMB) Control Number 9000-0010, titled Progress Payments, SF 1443. The rule affects information collection requirements in DFARS 252.232-7002, Progress Payments for Foreign Military Sales Acquisitions, currently approved under OMB Control Number 0704-0321, titled DFARS Part 232, Contract Financing, and the Clause at 252.232-7002, Progress Payments for Foreign Military Sales Acquisition. The impact, however, is negligible because the changed reporting requirement is not anticipated to increase the estimate of total burden hours; rather the requirement to submit separate payment requests by rate is merely replaced by a requirement to submit separate payment requests for FMS and U.S. line items in the contract. List of Subjects in 48 CFR Parts 204 , 232 , and 252 Government procurement Jennifer D. Johnson, Editor/Publisher, Defense Acquisition Regulations System. Therefore, 48 CFR

parts 204 , 232 , and 252 are amended as follows: 1. The authority citation for 48 CFR parts 204 , 232 , and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 . PART 204-ADMINISTRATIVE AND INFORMATION MATTERS 2. Amend section 204.7109 by revising paragraph (b) to read as follows: 204.7109 Contract clauses. * * * * (b) Use the clause at 252.204-7006, Billing Instructions-Cost Vouchers, in solicitations and contracts when a cost-reimbursement contract, a time-and-materials contract, or a labor-hour contract is contemplated. PART 232-CONTRACT FINANCING 3.

As prescribed in 209.409, use the following clause: SUBCONTRACTING WITH FIRMS THAT ARE OWNED OR CONTROLLED BY THE GOVERNMENT OF A COUNTRY THAT IS A STATE SPONSOR OF TERRORISM (DEC 2014) (a) Unless the Government determines that there is a compelling reason to do so, the Contractor shall not enter into any subcontract in excess of \$30,000 with a firm, or a subsidiary of a firm, that is identified in the Exclusions section of the System for Award Management System (SAM Exclusions) as being ineligible for the award of Defense contracts or subcontracts because it is owned or controlled by the government of a country that is a state sponsor of terrorism. (b) A corporate officer or a designee of the Contractor shall notify the Contracting Officer, in writing, before entering into a subcontract with a party that is identified, in SAM Exclusions, as being ineligible for the award of Defense contracts or subcontracts because it is owned or controlled by the government of a country that is a state sponsor of terrorism. The notice must include the name of the proposed subcontractor and the compelling reason(s) for doing business with the subcontractor notwithstanding its inclusion in SAM Exclusions. (End of clause) 15. Add section 252.225-7050 to read as follows: 252.225-7050 Disclosure of Ownership or Control by the Government of a Country that is a State Sponsor of Terrorism. As prescribed in 225.771-5, use the following provision: DISCLOSURE OF OWNERSHIP OR CONTROL BY THE GOVERNMENT OF A COUNTRY THAT IS A STATE SPONSOR OF TERRORISM (DEC 2014) (a) Definitions. As used in this provision: Government of a country that is a state sponsor of terrorism includes the state and the government of a country that is a state sponsor of terrorism, as well as any political subdivision, agency, or instrumentality thereof. Significant interest means: (i) Ownership of or beneficial interest in 5 percent or more of the firm's or subsidiary's securities. Beneficial interest includes holding 5 percent or more of any class of the firm's securities in :nominee shares, :street names, or some other method of holding securities that does not disclose the beneficial owner; (ii) Holding a management position in the firm, such as a director or officer; (iii) Ability to control or influence the election, appointment, or tenure of directors or officers in the firm; (iv) Ownership of 10 percent or more of the assets of a firm such as equipment, buildings, real estate, or other tangible assets of the firm; or (v) Holding 50 percent or more of the indebtedness of a firm. State sponsor of terrorism means a country determined by the Secretary of State, under section 6(j)(1)(A) of the Export Administration Act of 1979 (50 U.S.C. App. 2405(j)(1)(A)), to be a country the government of which has repeatedly provided support for acts of international terrorism. As of the date of this provision, state sponsors of terrorism include: Cuba, Iran, Sudan, and Syria. (b) Prohibition on award. In accordance with 10 U.S.C. 2327

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.11.11E Discoverable Information 1612 Determine information about the system that is discoverable and take [Assignment: organization-defined corrective actions]. DISCUSSION Discoverable information includes information that adversaries could obtain without compromising or breaching the system, such as by collecting information that the system is exposing or by conducting extensive web searches. Corrective actions include notifying organizational personnel, removing designated information, or changing the system to make the designated information less relevant or attractive to adversaries. This requirement excludes intentionally discoverable information that may be part of a decoy capability (e.g., honeypots, honeynets, or deception nets) implemented by the organization. This

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. In today's cloud data centers and edge computing, attack surfaces have significantly increased, cyber attacks are industrialized, and most security control implementations are not coherent or

consistent. The foundation of any data center or edge computing security strategy should be securing the platform on which data and workloads will be executed and accessed. The physical platform represents the foundation for any layered security approach and provides the initial protections to help ensure that higher-layer security controls can be trusted. This report explains an approach based on hardware-enabled security techniques and technologies for safeguarding container deployments in multi-tenant cloud environments. It also describes a prototype implementation of the approach intended to be a blueprint or template for the general security community. There are security and privacy concerns with allowing unrestricted container deployment orchestration. A common desire is to only use cloud servers physically located within the same country as the organization, or physically located in the same country as the origin of the information.

(B) From subsections (d) and (f) because providing access to investigative records and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because this system of records is compiled for investigative purposes and is exempt from the access provisions of subsections (d) and (f). (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. (19) [Reserved] (20) System identifier and name. F033 AF A, Information Requests-Freedom of Information Act. (i) Exemption. During the processing of a Freedom of Information Act request, exempt materials from `other' systems of records may in turn become part of the case record in this system. To the extent that copies of exempt records from those other systems of records are entered into this system, the Department of the Air Force hereby claims the same exemptions for the records from those `other' systems that are entered into this system, as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a

recognizes that widespread health IT adoption ·has the potential to ameliorate many of the quality and efficiency problems endemic to our health care system.· Congress also understood that ·[e]nsuring the privacy and security of electronic health information is critical to the success· of this immense effort to promote health IT adoption. [54] As a result, the HITECH Act also introduced substantial changes to the HIPAA regulations by mandating stronger safeguards for the privacy and security of ePHI. [55] The HITECH Act's security requirements focused on safeguarding an individual's health information while allowing covered entities to rapidly adopt new technologies to improve the quality and efficiency of patient care. [56] Specifically, the HITECH Act extends the application of the Security Rule's provisions on administrative, physical, and technical safeguards and documentation requirements to business associates of covered entities, making those business associates subject to civil and criminal liability for violations of the Security Rule. [57] The HITECH Act also requires existing business associate agreements to incorporate new security requirements. [58] Additionally, the HITECH Act requires the Secretary to regularly issue guidance on the most effective and appropriate technical safeguards. [59] In enacting the HITECH Act, Congress affirmed that the existing HIPAA Rules were to remain in effect to the extent that they are consistent with the HITECH Act and directed the Secretary to revise the HIPAA Rules as necessary for consistency with the HITECH Act. [60] Congress confirmed that the new law was not intended to have any effect on authorities already granted under HIPAA to the Department, including part C of title XI of the SSA. [61] Thus, Congress affirmed the Secretary's ongoing rulemaking authority to modify the Security Rule's standards and implementation specifications as often as every 12 months when appropriate, including to strengthen

security protections for IIHI. In 2021, the HITECH Act was amended to require the HHS Secretary to further encourage regulated entities to bolster their cybersecurity practices. [62] The amendment requires the Department to consider certain recognized security practices of regulated entities when making determinations relating to certain Security Rule compliance and enforcement activities. [63] B. Regulatory History The Security Rule requires regulated entities to implement administrative, physical, and technical safeguards to (printed page 904) protect ePHI. [64] Specifically, regulated entities must ensure the confidentiality, integrity, and availability of all ePHI they create, receive, maintain, or transmit; [65] protect against reasonably anticipated threats or hazards to the security or integrity of the information [66] and reasonably anticipated impermissible uses or disclosures; [67] and ensure compliance by their workforce. [68] 1. 1998 Security Rule Notice of Proposed Rulemaking

A preamble overview paragraph about Affirming Officials is revised to clarify that CMMC affirmations shall be submitted by the OSA and apply only to the information systems of that organization. DoD's use of the term OSA within the affirmations section is deliberate and conveys that each organization is responsible for affirmations pertaining to their own assessments. A preamble overview paragraph about Cloud Service Providers has been aligned to DFARS clause 252.204-7012 language and specifies that defense contractors must confirm that any CSPs they use to handle CUI must meet FedRAMP Moderate Baseline standards. Wording in the preamble overview of the rule has been edited from ·may include· to ·require·, to clarify a statement about when DFARS clause 252.204-7012 applies. One sentence in the preamble about the regulatory impact of CMMC Requirements has been edited into two sentences to make clear that solicitations identify CMMC contract requirements, rather than ·for contractors·, and that only contractors handling FCI or CUI must meet the specified CMMC requirements. The DoD has incorporated a suggested re-wording to simplify the description of CMMC Level 2 assessments in the preamble paragraph describing Key Changes Incorporated in the Revised CMMC Program. b. Changes to the Regulatory Text Comment: Of the 52 comments that requested changes to the regulatory text (§§ 170.1 through 170.24), the nine which DoD incorporated are summarized below. Word choices: In § 170.1(b), two comments posited that the word ·enhance· is inaccurate in the phrase (printed page 83165) ·The CMMC Program is designed to enhance protection of FCI and CUI In § 170.9(a) one comment noted that C3PAOs do not ·grant· assessments, they ·conduct· them. Another asked why, in table 3 to § 170.19(c)(1), the CUI Asset category needs to be assessed against ·CMMC security requirements· but in table 5 to § 170.19(d)(1), the same category is assessed against ·all CMMC security requirements·. For § 170.4(b) One comment requested appending ·and to the DoD· to the definition of Assessment Findings Report. Paragraph Organization: For Applicability, a comment recommended changing the order of paragraphs in § 170.3 and other text changes to improve clarity. Reference: One comment noted that the § 170.6(b) phrase ·as provided for under DFARS clauses 252.204-7012 and 7020 . . . is in error because the section describes CMMC PMO responsibilities and only DFARS clause 252.204-7020 references DIBCAC assessments of OSAs. Redundancy: One comment asserted that § 170.9(b)(9) and § 170.9(b)(20) are redundant as both describe that assessment appeals and results are entered into eMASS. Consistency: One comment pointed out an inconsistency between the text in § 170.18(c)(1)(i) and the Scoping Guide related to whether a CMMC Level 3 Assessment Scope must be the same as, or may be a subset of, the Assessment Scope of the prerequisite CMMC Level 2 certification. Clarifications:

Defense Federal Acquisition Regulation Supplement (DFARS), Part 204, Administrative Matters and Related Clauses at 252.204; OMB Control Number 0704-0225. Needs and Uses: DFARS 204.404-70(a) prescribes the use of the clause at DFARS 252.204-7000, Disclosure of Information, when the contractor will have access to or generate unclassified information that may be sensitive and inappropriate for release to the public. Upon receipt of a contractor's request, the Government reviews the information provided by the contractor to determine if it is sensitive or otherwise inappropriate for release for the stated purpose. Affected Public: Businesses or other for-profit and not-for profit institutions. Number of Respondents: 1,196. Responses per Respondent: Approximately 2.35. Annual Responses: 2,806. Average Burden per Response: Approximately 3 hours. Annual Burden Hours: 8,418. Reporting Frequency: On occasion. Summary of Information Collection DFARS 204.404-70(a) prescribes use of DFARS Clause 252.204-7000, Disclosure of Information, in contracts that require the contractor to access or generate unclassified information that may be sensitive and inappropriate for release to the public. The clause requires the contractor to obtain approval of the contracting officer before release of any unclassified contract-related information outside the contractor's organization, unless the information is already in the public domain. In requesting this approval, the contractor must identify the specific information to be released, the

An attack graph is often perceived to have a deterministic semantics: as long as all the preconditions of an attack can be achieved, the attack can always succeed resulting in the attacker obtaining the postcondition privilege. In reality, it is often not that clear. The 'possibly execute arbitrary code' in the vulnerability's overview highlights the uncertainty in the true consequence of exploiting a vulnerability. Depending on the difficulty level of the exploit, the attacker's skills and resources, and how hard it is to get to it, a vulnerability may or may not pose a high risk to the system. Since all security hardening measures (e.g. , patching) inevitably incur cost in terms of human labor, increased inconvenience, or degraded performance, security administration is an art of balancing risk and cost. A quantitative model for risk assessment is indispensable to make this effort a more scientific process. Table 1 shows the metric calculation results based on the method of Homer et al. [34]. Column 2 shows the risk metrics for Example 3. Columns 3-6 show the new risk assessment values based on various mitigation options: patching different vulnerabilities or changing the firewall rules so that the user workstations cannot access the database server. We try to give intuitive reasons to justify the security risk scores for each of the options. Patching the vulnerability on the web server would eliminate the known risk of compromise for the web server, but would have little effect on the other two hosts. The web server does not contain sensitive information, so protecting this host may not be the best choice. Even if the web server vulnerability gets patched, there are other attack paths. For example, an attacker can first gain control of a user workstation and then launch attacks against the database server from the workstation.

LTE infrastructure components (e.g., eNodeB, MME, S-GW) rely on purpose built systems to perform their network functions. The core software these systems run on is often a general purpose operating system. It is important that computer security recommended practices, including network, physical, and personnel security, be applied to these components in the same way they are applied to general information technology systems throughout industry today. Protection mechanisms such as patch management, configuration management (e.g., disabling serial ports on field network equipment), identity and access management, malware detection, and intrusion detection and prevention systems can be carefully planned and implemented throughout the MNO's LTE infrastructure. These processes and protection mechanisms can be tailored to best support and protect the specialized LTE system.

, as it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From 5 U.S.C. 552a(e)(4)(G) , (H), and (I), as it will provide protection against notification of investigatory material which might alert a subject to the fact that an investigation of that individual is taking place, and the disclosure of which would weaken the ongoing investigation, reveal investigatory techniques, and place in jeopardy confidential informants who furnished information under an express promise that the sources' identity would be held in confidence (or prior to the effective date of the Act, under an implied promise). (4) System identifier and name. S500.30 (Specific exemption), Incident Investigation/Police Inquiry Files. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . If an individual, however, is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information, except to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(4)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) The specific sections of 5 U.S.C. 552 a from which the system is exempt are 5 U.S.C. 552a(c)(3) , (d)(1) through (d)(4), (e)(1), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons. (A) From 5 U.S.C. 552a(c)(3) , because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the

subject to the existence of the investigation or prosecutive interest by DLA or other agencies. This could seriously compromise case preparation by: Prematurely revealing its existence and nature; compromising or interfering with witnesses or making witnesses reluctant to cooperate; and leading to suppression, alteration, or destruction of evidence. (B) From 5 U.S.C. 552a(d)(1) through (d)(4) , and (f)

, FAR 32.201 provides that payment for commercial items may be made under such terms and conditions as the agency head determines are appropriate or customary in the commercial marketplace and are in the best interest of the United States. Furthermore, FAR 32.202-1 states that Government financing of commercial purchases is expected to be different from that used for noncommercial purchases. While the contracting officer may adapt techniques and procedures from the noncommercial subparts for use in implementing commercial contract financing arrangements, the contracting officer must have a full understanding of effects of the differing contract environments and of what is needed to protect the interests of the Government in commercial contract financing.

IV. Expected Cost Impact

This rule amends the DFARS to implement changes to performance-based payment policies for DoD contracts by amending the policy on performance-based payments at DFARS 232.1001 and amending the clauses at DFARS 252.232-7012, Performance-Based Payments-Whole Contract Basis, and 252.232-7013, Performance-Based Payments-Deliverable Item Basis. This rule may benefit contractors who receive contract financing from the Government in the form of performance-based payments. Performance-based payments do not apply to: Payments under cost-reimbursement line-items; Contracts awarded under the authority of FAR part 12 or part 13; Contracts for architect-engineer services or construction, or for shipbuilding or ship repair, when the contract provides for progress payments based upon a percentage or stage of completion. Performance-based payments are tied to the achievement of specific, measurable events or accomplishments that are defined and valued in advance by the parties to the contract. Total performance-based payments cannot exceed 90 percent of the contract price. This rule removes the DFARS restrictions that limit performance-based payments to amounts not greater than costs incurred up to the time of payment. If performance-based payments to the contractor based on the negotiated value of completed milestone events are allowed to exceed the total costs incurred up to the time of payment, the cost to the contractor of short-term borrowing will decrease and the cost to the Government of borrowing will increase. In addition, there is a minimal cost to offerors and the Government related to a new provision at DFARS 252.232-7015, Performance-Based Payments-Representation, which requires each offeror responding to a solicitation that may result in a contract providing performance-based financing to represent whether the offeror's financial statements are in compliance with Generally Accepted Accounting Principles.

The CMMC Program verifies defense contractor compliance with DoD's cybersecurity information protection requirements. It is designed to protect FCI and CUI that is shared by the Department with, or generated by, its contractors and subcontractors. The cybersecurity standards required by the program are the same as those set forth in FAR clause 52.204-21 (CMMC Level 1), the NIST SP 800-171 R2 guidelines, which is presently required by DFARS clause 252.204-7012 (CMMC Level 2), and additional selected requirements from the NIST SP 800-172 Feb2021 guidelines (CMMC Level 3). The program adds a robust assessment element and provides the Department increased assurance that contractors and subcontractors are meeting these requirements. In September 2020, the DoD published the 48 CFR CMMC interim final rule to the DFARS in the Federal Register (DFARS Case 2019-D041, 85 FR 48513 , September 9, 2020), which implemented the DoD's vision for the initial CMMC Program and outlined the basic features of the program (tiered model, required assessments, and implementation through contracts). The 48 CFR CMMC interim final rule became effective on November 30, 2020, establishing a five-year phase-in period. In March 2021, the Department initiated an internal review of CMMC's implementation, informed by more than 750 CMMC-related public comments in response to the 48 CFR CMMC interim final rule. This comprehensive, programmatic assessment engaged cybersecurity and acquisition leaders within DoD to refine policy and program implementation. In November 2021, the Department announced plans for a revised CMMC Program, which incorporates an updated program structure and requirements designed to achieve the primary goals of an internal DoD review of the CMMC Program. With the implementation of the CMMC Program, the Department introduced several key changes that build on and refine the original program requirements. These include: Streamlining the model from five to three certification levels; Allowing all companies at Level 1 and a subset of companies at Level 2 to demonstrate compliance through self-assessments; Increased oversight of professional and ethical standards of third-party assessors; and Allowing companies, under certain limited circumstances, to make POA&Ms to achieve certification. In December 2023, the Department published a proposed rule to amend 32 CFR part 170 in the Federal Register (Docket ID

2023-OS-0063, 88 FR 89058 , December 26, 2023), which implemented the DoD's vision for the revised CMMC Program outlined in November 2021. The comment period for the proposed rule concluded on February 26, 2024.

Where multiple persons have control over a technology asset, all persons that have control should include the asset in both their technology asset inventories and on their network maps. For example, where a covered entity contracts with a cloud-based EHR vendor, both the covered entity and the EHR vendor have control over the ePHI in the EHR. Thus, the ePHI in the EHR and the EHR should be included in the technology asset inventories and network maps of both the covered entity and the cloud-based EHR vendor. Where the technology assets are controlled entirely by another person, such as the servers controlled by a cloud-based provider of data backup services, the technology assets would not be considered part of a health care provider's electronic information systems, and therefore would not have to be included in its technology asset inventory. However, the data backup provider would have to be included in the health care provider's network map. When creating or maintaining a technology asset inventory that can aid in identifying risks to ePHI, regulated entities should consider their technology assets that may not create, receive, maintain or transmit ePHI, but that may affect technology assets that do so. [458] Assets within an organization that do not create, receive, maintain, or transmit ePHI may still present opportunities for intruders to enter the regulated entity's electronic information systems, which could lead to risks to the confidentiality, integrity, or availability of an organization's ePHI. For example, consider a smart device that is connected to the internet (e.g., connected to the Internet of Things [459] (IoT)) and provides access to facilities for maintenance personnel to control and monitor an organization's heating, ventilation, and air conditioning (HVAC). Although it may not maintain or process ePHI, such a device potentially can present serious risks to the security of ePHI in an organization's information systems. Unpatched IoT devices with known vulnerabilities, such as weak or unchanged default passwords installed on a network without firewalls, network segmentation, or other techniques that deny or impede an intruder's lateral movement, can provide an intruder with access to an organization's relevant electronic information systems. The intruder may then leverage this access to conduct reconnaissance and further penetrate an organization's network and potentially compromise ePHI. The risks and deficiencies OCR has observed in its enforcement experience persuades us that we must consider adding an express requirement for a regulated entity to conduct an accurate and thorough written inventory of its technology assets and create a network map. d. Section 164.308(a)(2)(i)·Standard: Risk Analysis

<!-- image --> ## NIST Cybersecurity & Privacy Program FY 2024 Annual Report <!-- image -->
Fiscal Year 2024 Annual Report for NIST Cybersecurity and Privacy Program Patrick O'Reilly,
Editor Computer Security Division Information Technology Laboratory Kristina Rigopoulos, Editor
Applied Cybersecurity Division Information Technology Laboratory This publication is available free
of charge from: <https://doi.org/10.6028/NIST.SP.800-236> April 2025 <!-- image --> U.S. DEPARTMENT
OF COMMERCE Howard Lutnick, Secretary <!-- image --> <!-- image --> ## Foreword 4 Introduction
4 - PRIORITY AREAS - - Cryptography 5 - Education & Workforce 7 - Emerging Technology 9 -
HumanCentered Cybersecurity 11 - Identity & Access Management 13 - Privacy 15 - Risk Management
17 - Trusted Networks & Platforms 19 - National Cybersecurity Center of Excellence (NCCoE) 21 -
Stakeholder Engagement & Events 24 <!-- image --> <!-- image --> -----
Back to the future. As we look back on our past fiscal year's work in cybersecurity and privacy, we
can see the fruition of many long-standing efforts that will position us well in the changing times
ahead. NIST has set foundations to ensure our security and privacy now and into the future with new
quantumresistant encryption algorithms, updates to the NIST Cybersecurity Framework, and the
establishment of Artificial Intelligence programs, testbeds, and research agendas. Our research has
also demonstrated practical applications of our work that spans several key priority areas that are
outlined in this report with hyperlinked pointers to help you dig deeper and learn more.

particularly want to thank Rebecca Bace of KSR for her careful review of the publication and for her
work on the predecessor publication, NIST Special Publication 800-31, Intrusion Detection Systems .
The authors would also like to express their thanks to security experts Andrew Balinsky (Cisco
Systems), Anton Chuvakin (LogLogic), Jay Ennis (Network Chemistry), John Jerrim (Lancop), and Kerry
Long (Center for Intrusion Monitoring and Protection, Army Research Laboratory), as well as
representatives from the Department of State and Gartner, for their particularly valuable comments
and suggestions. Additional acknowledgements will be added to the final version of the publication.

Control PS-15413: ons into acquisition activities within every step of the procurement and contract management life cycle process is essential to improving management of cybersecurity risks throughout the supply chain. This life cycle begins with a purchaser identifying a need and includes the processes to plan for and articulate requirements, conduct research to identify and assess viable sources of supply, solicit bids, evaluate offers to ensure conformance with C-SCRM requirements, and assess C-SCRM risks associated with the bidder and the proposed product and/or service. After contract award, ensure that the supplier satisfies the terms and conditions articulated in the contractual agreement and that the products and services conform as expected and required. Monitoring for changes that may affect cybersecurity risks in the supply chain should occur throughout the life cycle and may trigger reevaluation of the original assessment or require a mitigation response. Enterprises rely heavily on commercial products and outsourced services to perform operations and fulfill their mission and business objectives. However, it is important to highlight that products and services can also be obtained outside of the procurement process, as is the case with open source software, relying on an in-house provider for shared services, or by repurposing an existing product to satisfy a new need. C-SCRM must also be addressed for these other 'acquiring' processes. In addition to addressing cybersecurity risks throughout the supply chain and performing C-SCRM activities during each phase of the acquisition process, enterprises should develop and execute an acquisition strategy that drives reductions in their overall risk exposure. By applying 25 Departments and agencies should refer to Appendix F to implement this guidance in accordance with Executive Order 14028, Nation's Cybersecurity .

to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided to the President and others are not compromised, to protect records used solely as statistical records, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, and to preserve the confidentiality and integrity of Federal evaluation materials. The exemption rule for the original records will identify the specific reasons why the records may be exempt from specific provisions of 5 U.S.C. 552a . (22) System identifier and name. A0351-12 DAPE, Applicants/Students, U.S. Military Academy Prep School. (i) Exemption. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (B) Evaluation material used to determine potential for promotion in the Military Services may be exempt pursuant to 5 U.S.C. 552a(k)(7) , but only to the extent that the disclosure of such material would reveal the identity of a confidential source. (C) It is imperative that the confidential nature of evaluation material on individuals, furnished to the U.S. Military Academy Preparatory School under an express promise of confidentiality, be maintained to ensure the candid presentation of information necessary in determinations involving admission to or retention at the United States Military Academy and suitability for commissioned military service. (D) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(5) and (k)(7) subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) and (k)(7) . (iii) Reasons. (A) From subsections (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement.

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement is sourced to a control tailored out of the SP 800-53B [13] moderate baseline in SP 800-171. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 PROTECTION STRATEGY 2555

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology promotes the United States economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof-of-concept implementations, and technical analyses to advance the development and productive

use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of non-national-security-related information in federal information systems. This Special Publication 800 series reports on ITL's research, guidelines, and outreach efforts in information system security and its collaborative activities with industry, government, and academic organizations. applications 3 are not required because the security controls for those applications are typically provided by the general support system or major application in which they operate. In those cases where the minor application is not connected to a major application or general support system, the minor application should be briefly described in a general support system plan that has either a common physical location or is supported by the same organization. Additional information is provided in Chapter 2. system to the high watermark or highest impact level must be applied when grouping minor applications/subsystems with varying FIPS 199 impact levels into a single general support system or major application unless there is adequate boundary protection, e.g., firewalls and encryption, around those subsystems or applications with the highest impact level. Additionally, there must be assurance that the shared resources, i.e., networks, communications, and physical access within the whole general support system or major application, are protected adequately for the highest impact level.

or any other applicable information protection requirements. The CMMC Program provides a means of verifying implementation of the security requirements set forth in 48 CFR 52.204-21, NIST SP 800-171 R2, and NIST SP 800-172 Feb2021, as applicable. Subpart B-Government Roles and Responsibilities. §-170.6 CMMC PMO. (a) The Office of the Department of Defense Chief Information Officer (DoD CIO) Office of the Deputy CIO for Cybersecurity (DoD CIO(CS)) provides oversight of the CMMC Program and is responsible for establishing CMMC assessment, accreditation, and training requirements as well as developing and updating CMMC Program policies and implementing guidance. (b) The CMMC PMO is responsible for monitoring the CMMC AB's performance of roles assigned in this rule and acting as necessary to address problems pertaining to effective performance. (c) The CMMC PMO retains, on behalf of the DoD CIO(CS), the prerogative to review decisions of the CMMC Accreditation Body as part of its oversight of the CMMC program and evaluate any alleged conflicts of interest purported to influence the CMMC Accreditation Body's objectivity. (d) The CMMC PMO is responsible for sponsoring necessary DCSA activities including FOCl risk assessment and Tier 3 security background investigations for the CMMC Ecosystem members as specified in §§-170.8(b)(4) and (5), 170.9(b)(3) through (5), 170.11(b)(3) and (4), and 170.13(b)(3) and (4). (e) The CMMC PMO is responsible for investigating and acting upon indications that an active CMMC Status has been called into question. Indications that may trigger investigative evaluations include, but are not limited to, reports from the CMMC Accreditation Body, a C3PAO, or anyone knowledgeable of the security processes and activities of the OSA. Investigative evaluations include, but are not limited to, reviewing pertinent assessment information, and exercising the right to conduct a DCMA DIBCAC assessment of the OSA, as provided for under the 48 CFR 252.204-7020. (f) If a subsequent DCMA DIBCAC assessment shows that adherence to the provisions of this rule and the required CMMC Status have not been achieved or maintained, the DIBCAC results will take precedence over any pre-existing CMMC Status recorded in SPRS, or its successor capability. The DoD will update SPRS to reflect that the OSA is out of compliance and does not meet DoD CMMC requirements. If the OSA is working on an active contract requiring CMMC compliance, then standard contractual remedies will apply. §-170.7 DCMA DIBCAC. (a) DCMA DIBCAC assessors in support of the CMMC Program will: (1) Complete CMMC Level 2 and Level 3 training. (2) Conduct Level 3 certification assessments and upload assessment results into the CMMC instantiation of eMASS, or its successor capability. (3) Issue Certificates of CMMC Status resulting from Level 3 certification assessments. (4) Conduct Level 2 certification assessments of the Accreditation Body and prospective C3PAOs' information (printed page 83221)

(2) If the GCA does not provide a remedy, and the contractor still believes that corrective action is required, the contractor will make a formal written challenge to the GCA. The challenge will include: (i) A description sufficient to identify the issue. (ii) The reasons why the contractor thinks that corrective action is required. (iii) Recommendations for appropriate corrective action. (3) The contractor will safeguard the information as required for its assigned or proposed level of classification, whichever is higher, until action is completed. (4) If the contractor does not receive a written answer from the GCA within 60 days, the contractor will request assistance from the CSA. If the contractor does not receive a response from the GCA within 120 days, the contractor may appeal the challenge to the Interagency Security Classification Appeals Panel through ISOO. (5) The fact that a contractor has initiated such a challenge will not, in any way, serve as a basis for

adverse action against the contractor by the USG. If a contractor believes that adverse action did result from a classification challenge, the contractor will promptly furnish full details to ISOO for resolution. (f) Contractor developed information. Whenever a contractor develops an unsolicited proposal or originates information not in the performance of a classified contract, the provisions of this paragraph apply. (1) If the information was previously identified as classified, it will be classified according to an appropriate classification guide, or source document, and appropriately marked. (2) If the information was not previously classified, but the contractor believes the information may or should be classified, the contractor will: (i) Protect the information as though classified at the appropriate level. (ii) Submit the information to the agency that has an interest for a classification determination. In such cases, clearly mark the material ·CLASSIFICATION DETERMINATION PENDING; Protect as either TOP SECRET, SECRET, or CONFIDENTIAL.· This marking will appear conspicuously at least once on the material but no further markings are necessary until a classification determination is received. (iii) Not be precluded from marking such material as entity-private or entity-proprietary information, unless the material was based upon information obtained from prior deliverables to the USG or was developed from USG material. (iv) Protect the information pending a final classification determination. The information may be CUI, if it is not classified. Only information that is owned by, produced by, produced for, or is under the control of the USG can be classified in accordance with E.O. 13526 . (3) To be eligible for classification: (i) The information must incorporate classified information to which the contractor was given prior access. (ii) The information must be partially or wholly owned by, produced by or for, or under the control of the USG. (4) 10 CFR 1045.21

CIS Safeguard 17.7 · Conduct Routine Incident Response Exercises Plan and conduct routine incident response exercises and scenarios for key personnel involved in the incident response process to prepare for responding to real-world incidents. Exercises need to test communication channels, decision making, and workflows. Conduct testing on an annual basis, at a minimum. Implementation Groups: 2,3 Asset Type: N/A Security Function: recover Parent Control: Incident Response Management

Four comments questioned the eligibility and scope of the program, to include recommending that the program remain voluntary, and questioning whether the program was ·under inclusive or overly restrictive because the program is only available to companies that have a Facility Security Clearance and a Communications Security account.· Response: The DIB CS/IA program will remain a voluntary program to enhance and supplement DIB participants' capabilities to safeguard DoD information that resides on, or transits, DIB unclassified information systems. The eligibility requirements for the program (§ 236.7) are based on security requirements to ensure the protection of Government furnished information (GFI) at DIB companies in possession of DoD information, as described in the definition for ·covered defense information,· (§ 236.2(c)). No change is made to the rule. Comment: One comment asserted that the rule should not have been published as an interim rule. Response: In light of the growing cyber threat activity against DoD information and DIB information systems and the associated risk to U.S. national security, the Government determined it appropriate to issue an interim rule. This allowed eligible DIB companies to receive cyber threat information, without delay in order to enhance their capability to defend against ongoing and continuous cyber threats and to safeguard DoD information. No change is made to the rule. Comment: One comment asserted that the Framework Agreement (FA) should be available for public review to evaluate the estimates of projected paperwork for participants. Response: The Framework Agreement is a representation of the federal rule converted into an agreement format for implementation of the program. In addition, all information required to evaluate the projected cost and time for the information collection requirements is available in the rule. No change is made to the rule. Comment: One comment asserted that transparency into public-private cyber security programs is crucial to ensure that federal agencies respect privacy rights and comply with their obligations. Response: Extensive coordination across the Government has ensured that the privacy rights of U.S. citizens are protected under the DIB CS/IA voluntary program, including developing a comprehensive Privacy Impact Assessment (PIA) for the DIB CS/IA program. The PIA is publically available at: http://dodcio.defense.gov/·Portals/·0/·Documents/·DIB%20CS-IA%20PIA_·FINAL_·signed_·30jun2011_·VMSS_·GGMR_·RC.pdf . No change is made to the rule. Comment: One comment asserted that the Defense Department opted to issue a rule even though no law has been passed by Congress regarding Government-industry cyber security activities and that rulemaking should come after Congress concludes its legislative efforts. Response:

Document Headings Document headings vary by document type but may contain the following: the

agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [Docket Number DARS-2019-0021; OMB Control Number 0704-0478] AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Notice. SUMMARY: The Defense Acquisition Regulations System has submitted to OMB for clearance, the following proposal for collection of information under the provisions of the Paperwork Reduction Act. DATES: Consideration will be given to all comments received by August 29, 2019. SUPPLEMENTARY INFORMATION: A. Title and OMB Number Safeguarding Covered Defense Information, Cyber Incident Reporting, and Cloud Computing; OMB Control Number 0704-0478. B. Needs and Uses Offerors and contractors must report cyber incidents on unclassified networks or information systems, within cloud computing services, and when they affect contractors designated as providing operationally critical support, as required by statute. C. Annual Burden Number of Respondents: 2,017. Responses per Respondent: 17.35. Annual Responses: 34,974. Average Burden per Response: .29 hours. Annual Burden Hours: 10,071. Reporting Frequency: On Occasion. Affected Public. Businesses or other for-profit and not-for-profit institutions. Respondent's Obligation: Required to obtain or retain benefits. Frequency: On occasion. Type of Request: Renewal of a currently approved collection. (printed page 36906) D. Public Comments A 60-day notice was published in the Federal Register at 84 FR 23532 on May 22, 2019. One respondent provided four comments, which are summarized below along with responses; however, the comments did not change the estimate of the burden. Comment: To ensure proper safeguarding of contractors' attributional/proprietary information, the respondent recommends that the contractor submitting the information be: (1) Afforded an opportunity to review and propose redactions prior to release; (2) permitted to apply protective markings to information after its submission to the Government; and (3) allotted additional time to pursue any administrative or legal remedies in the event that the Government plans to disclose information that the contractor has otherwise proposed to be withheld. Response:

to the extent such provisions have been identified and an exemption claimed for the original record and the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided to the President and others are not compromised, to protect records used solely as statistical records, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records may be exempt from specific provisions of 5 U.S.C. 552a . (30) System identifier and name. A0601-141 DASG, Applications for Appointment to Army Medical Department. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. Therefore, portions of the system of records may be exempt pursuant to 5 U.S.C. 552(a)(k) (5) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought.

Establish and implement written policies and procedures for granting and revising access to electronic protected health information and relevant electronic information systems as necessary and appropriate for each prospective user and technology asset to carry out their assigned function(s).

(C) Authentication management. Establish and implement written policies and procedures for verifying the identities of users and technology assets prior to accessing the covered entity's or business associate's relevant electronic information systems, including written policies and procedures for implementing multi-factor authentication technical controls required by § 164.312(f)(2)(ii) through (v).

(D) Access determination and modification. Establish and implement written policies and procedures that, based upon the covered entity's or the business associate's access authorization policies, determine, document, review, and modify the access of each user and technology asset to specific components (printed page 1015) of the covered entity's or business associate's relevant electronic information systems.

(E) Network segmentation. Establish and implement written policies and procedures that ensure that a covered entity's or business associate's relevant electronic information systems are segmented to limit access to electronic protected health information to authorized workstations.

(F) Maintenance. Review and test the written policies and procedures required by this paragraph (a)(10)(ii) at least once every 12 months, and modify as reasonable and appropriate.

(11) Standard: Security awareness training

(i) General. Implement security awareness training for all workforce members on protection of electronic protected health information and information systems as necessary and appropriate for the members of the workforce to carry out their assigned function(s).

(ii) Implementation specifications

(A) Training. A covered entity or business associate must develop and implement security awareness training for all workforce members that addresses all of the following:

- (1) The written policies and procedures with respect to electronic protected health information required by this subpart as necessary and appropriate for the workforce members to carry out their assigned functions.
- (2) Guarding against, detecting, and reporting suspected or known security incidents, including but not limited to, malicious software and social engineering.
- (3) The written policies and procedures for accessing the covered entity's or business associate's relevant electronic information systems, including but not limited to: safeguarding passwords; setting unique passwords of sufficient strength to ensure the confidentiality, integrity, and availability of electronic protected health information; and limitations on sharing passwords.

(B) Timing. A covered entity or business associate must provide security awareness training as follows:

(1

To address the potential for a bad actor to exploit publicly known vulnerabilities, and consistent with NCVHS' recommendation, the Department proposes to add a new standard for vulnerability management at 45 CFR 164.312(h)(1) . [800] The proposed standard would require a regulated entity to deploy technical controls to identify and address technical vulnerabilities in the regulated entity's relevant electronic information systems. The deployment of technical controls should be consistent with the regulated entity's patch management policies and procedures at proposed 45 CFR 164.308(a)(4) . This proposed standard aligns with the Department's enhanced CPGs for Cybersecurity Testing and Third Party Vulnerability Disclosure by calling for regulated entities to employ multiple processes to discover technical vulnerabilities, including vulnerabilities in workstations and in technology assets provided by vendors and service providers. [801] For example, a regulated entity should include a device owned by a person other than the regulated entity (e.g., the medical device manufacturer) in its vulnerability management activities where the device is deployed on the regulated entity's network. The regulated entity should also include all workstations (e.g., desktop computers, mobile devices) that are part of its relevant electronic information systems in its vulnerability management activities. To implement this proposed standard, we propose four implementation specifications. Proposed 45 CFR 164.312(h)(2)(i)(A) would require a regulated entity to conduct automated scans of the regulated entity's relevant electronic information systems, including all of the components of such relevant electronic information systems (e.g., workstations, private networks) to identify technical vulnerabilities. Vulnerability scans detect vulnerabilities such as obsolete software (printed page 978) and missing patches. [802] Once identified, assessed, and prioritized, appropriate measures need to be implemented to mitigate these vulnerabilities (e.g., apply patches, harden systems, retire equipment). [803] Under the proposal, the scans would be required to be conducted in accordance with the regulated entity's risk analysis under proposed 45 CFR 164.308(a)(2) and no less frequently than once every six months. Relatedly, proposed 45 CFR 164.312(h)(2)(i)(B) would add an implementation specification for maintenance of the technology

assets that conduct the required automated vulnerability scans. Under this proposal, a regulated entity would be expressly required to review and test the effectiveness of the technology asset(s) that conducts the automated vulnerability scans that would be required by the proposed implementation specification at proposed 45 CFR 164.312(h)(2)(i)(A) at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate.

From the NIST SP 800-172 Rev 3 Final Public Draft: As a result, when an adversary's attack on one supplier causes it to shut down, the defender can increase its use of the other suppliers, thus shortening the time when it is without the critical components. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [Docket DARS-2020-0007; OMB Control Number 0704-0519] AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Notice. SUMMARY: The Defense Acquisition Regulations System has submitted to OMB for clearance the following proposal for a new collection of information under the provisions of the Paperwork Reduction Act. DATES: Consideration will be given to all comments received by January 28, 2021. SUPPLEMENTARY INFORMATION: Title and OMB Number: Defense Federal Acquisition Regulation Supplement (DFARS); DFARS Subpart 204.17, Service Contracts Inventory and Associated Clause; OMB Control Number 0704-0519. Affected Public: Businesses and other for-profit entities. Respondent's Obligation: Required to obtain or retain benefits. Type of Request: Approval of a new information collection. Reporting Frequency: Annually. Number of Respondents: 1,934. Responses per Respondent: 2.267, approximately. Annual Responses: 4,386. Average Burden per Response: 2 hours. Total Annual Burden Hours: 8,772. Needs and Uses: 10 U.S.C. 2330a , as amended by section 812 of National Defense Authorization Act for Fiscal Year 2017, requires DoD to establish a data collection system to provide certain management information with regard to each purchase of services by a Military Department or Agency that is in excess of \$3 million for services in the following service acquisition portfolio groups: Logistics management services, equipment-related services, knowledge-based services, and electronics and communications services. New DFARS clause 252.204-70XX, Reporting Requirements for Contracted Services, requires a contractor to report annually, in the System for Award Management, on the services performed under the contract or order, during the preceding Government fiscal year. Specifically, the contractor is required to report the total dollar amount invoiced for services performed during the preceding fiscal year and the number of direct labor hours, including subcontractor hours (when applicable), expended on services performed during the previous Government fiscal year. The information collection will provide DoD with the ability to identify and report annually to Congress, in accordance with 10 U.S.C. 2330a , on the inventory of contractor service contract actions. As an adjunct, the information will support DoD's total force management and in making strategic workforce planning and budget decisions pursuant to 10 U.S.C. 129a .

Similarly, the RMF also demonstrates this bilateral relationship. For example, every task within the Prepare step of the RMF aligns with the Cybersecurity Framework Core. Specifically, the P-2 Risk Management Strategy aligns with the Cybersecurity Framework Core [Identify Function at ID.RM; ID.SC]. Other RMF examples include: Task P-4, Organizationally-Tailored Control Baselines and Cybersecurity Framework Profiles, aligns with the Cybersecurity Framework Profile construct; and Task R-5, Authorization Reporting, and Task M-5, Security and Privacy Reporting, support OMB reporting and risk management requirements organizationwide by using the Cybersecurity Framework constructs of Functions, Categories, and Subcategories. ² Still, it remains challenging to ensure a specific set of system configuration baseline settings is applied while maintaining compliance with multiple requirements (e.g., FISMA, HIPAA, PCI DSS, Special Publication 800-70 Revision 4, etc.). The NIST National Checklist Program provides a catalog of automated and implementable security settings to assist with the attestation trail from the applied setting to the framework. ⁶ In the RMF, after the system is categorized as a high, moderate, or low impact (based on FIPS 199/SP 800-60), organizations leverage FIPS 200 to identify minimum security requirements associated with the system impact level [12][16][17]. They then use the SP 800-53 tailoring process to apply any

other needed security to address specific mission objectives, operational constraints, cybersecurity requirements, and other organizational considerations. This process is used to customize the controls baseline for each system.

The HHS Office for Civil Rights estimated first-year compliance costs of approximately \$9 billion across all covered entities and business associates. This estimate accounts for the proposed requirements including mandatory encryption, MFA implementation, annual asset inventory and network mapping, and the elimination of the 'addressable' specification category. Individual organization costs will vary significantly based on size, current security posture, and technology infrastructure. Note: These are estimated costs for proposed changes. The final rule may differ from the NPRM.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 117 [Docket ID: DoD-2023-OS-0061] RIN 0790-AL52 AGENCY: Office of the Under Secretary of Defense for Intelligence & Security, Department of Defense (DoD). ACTION: Proposed rule. SUMMARY: DoD is proposing amendments to the National Industrial Security Program Operating Manual (NISPOM) based on public comments received on a final rule published on December 21, 2020. The proposed amendments address implementation guidance and costs for the Security Executive Agent Directive (SEAD) 3, clarifications on procedures for the protection and reproduction of classified information, controlled unclassified information (CUI), National Interest Determination (NID) requirements for cleared contractors operating under a Special Security Agreement for Foreign Ownership, Control or Influence, and eligibility determinations for personnel security clearance processes and requirements. DATES: Comments must be received on or before February 12, 2024. ADDRESSES: You may submit comments, identified by docket number and/or Regulatory Identifier Number (RIN) and title, by any of the following methods: Federal eRulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. Mail: Department of Defense, Office of the Assistant to the Secretary of Defense for Privacy, Civil Liberties, and Transparency, Regulatory Directorate, 4800 Mark Center Drive, Attn: Mailbox 24, Suite 08D09, Alexandria, VA 22350-1700. Instructions: All submissions received must include the agency name and (printed page 86289) docket number or RIN for this Federal Register document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing at <http://www.regulations.gov> as they are received without change, including any personal identifiers or contact information. FOR FURTHER INFORMATION CONTACT: Allyson Renzella, 703-697-9209. SUPPLEMENTARY INFORMATION: Background The NISPOM establishes requirements for the protection of classified information disclosed to or developed by contractors, licensees, grantees, or certificate holders to prevent unauthorized disclosure. The National Industrial Security Program (NISP) is established by Executive Order (E.O.) 12829 -National Industrial Security Program (NISP) (available at <https://www.archives.gov/files/isoo/policy-documents/eo-12829-with-eo-13691-amendments.pdf>

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense General Services Administration National Aeronautics and Space Administration 48 CFR Parts 1, 2, 4, 52, and 53 [FAR Case 2015-002; Docket No. 2015-0002, Sequence No. 1] RIN 9000-AN40 AGENCY: Department of Defense (DoD), General Services Administration (GSA), and National Aeronautics and Space Administration (NASA). ACTION: Proposed rule. SUMMARY: DoD, GSA, and NASA are proposing to amend the Federal Acquisition Regulation (FAR) to require electronic submission of the DD Form 254, Contract Security Classification Specification. DATES: Interested parties should submit written comments to the Regulatory Secretariat Division at one of the addresses shown below on or before September 10, 2019 to be considered in the formulation of a final rule. ADDRESSES: Submit comments in response to FAR Case 2015-002 by any of the following methods: Regulations.gov: <http://www.regulations.gov> . Submit comments via the Federal eRulemaking portal by searching for 'FAR Case 2015-002'. Select the link 'Comment Now' that

corresponds with ·FAR Case 2015-002·. Follow the instructions provided on the screen. Please include your name, company name (if any), and ·FAR Case 2015-002· on your attached document. Mail: General Services Administration, Regulatory Secretariat Division (MVCB), ATTN: Lois Mandell, 1800 F Street NW, Second Floor, Washington, DC 20405. Instructions: Please submit comments only and cite ·FAR case 2015-002· in all correspondence related to this case. All comments received will be posted, without change, to <http://www.regulations.gov> , including any personal and/or business confidential information provided. To confirm receipt of your comment(s), please check www.regulations.gov , approximately two to three days after submission to verify posting (except allow 30 days for posting of comments submitted by mail). FOR FURTHER INFORMATION CONTACT: Mr. Curtis E. Glover, Sr., Procurement Analyst, at (202) 501-1448 for clarification of content. For information pertaining to status or publication schedules, contact the Regulatory Secretariat Division at (202) 501-4755. Please cite ·FAR case 2015-002·. SUPPLEMENTARY INFORMATION: I. Background

Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is a significant regulatory action and, therefore, was subject to review under section 6(b) of E.O. 12866 , Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804 . IV. Regulatory Flexibility Act DoD does not expect this interim rule to have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601 , et seq., because companies have an existing interest in having a supply chain that it can rely on to provide it with material and supplies that allow the contractor to ultimately supply its customers with products that are safe and that do not impose threats or risks to government information systems. However, an Initial Regulatory Flexibility Analysis (IRFA) has been prepared because there is a growing interest by both the Government and industry in establishing cost efficient ways to protect the supply chain related to information technology purchases. Congress has recognized a growing concern for risks to the supply chain for technology contracts supporting the Department of Defense (DoD). Congress has defined supply chain risk as ·the risk that an adversary may sabotage, maliciously introduce unwanted function, or otherwise subvert the design, integrity, manufacturing, production, distribution, installation, operation, or maintenance of a covered system so as to surveil, deny, disrupt, or otherwise degrade the function, use, or operation of such system.· (See section 806(e)(4) of Pub. L. 111-383 .) The objective of this rule is to protect DoD against risks arising out of the supply chain. The legal basis for this rule is section 806 of the National Defense Authorization Act (NDAA) for Fiscal Year (FY) 2011 (Pub. L. 111-383), as amended by section 806 of the NDAA for FY 2013 (Pub. L. 112-239). Additionally, the Department of Defense Instruction (DoDI) 5200.44, Protection of Mission Critical Functions to Achieve Trusted Systems and Networks (TSN), recognizes the need to improve supply chain risk management (SCRM). In doing so, the DoDI requires, among other things, implementation of section 806 in the DFARS and in appropriate solicitation and contract language. This rule applies to contractors involved in the development or delivery of any information technology, whether acquired by DoD as a service or as a supply. This includes commercial purchases as well as purchases of commercial off-the-shelf (COTS) services or supplies.

A written confirmation, requested by and exchanged between governments, that contains the following elements: Verification of the personnel security clearance (PCL) level of the sponsoring foreign government's citizens or nationals; a statement by a responsible official of the sponsoring foreign government that the recipient of the information is approved by the sponsoring foreign government for access to information of the security classification involved on behalf of the sponsoring government; and an obligation that the sponsoring foreign government will ensure compliance with any security agreement or other use, transfer and security requirements specified by the components. The security assurance usually will be in a request for visit authorization or with courier orders or a transportation plan; but is not related to the PCL security assurance. Special Access Program (SAP). As defined in E.O. 13526 . Subcontract. As defined in DoD 5220.22-M. §117.54 Policy. It is DoD policy that DoD FOCI procedures will be used to protect against foreign interests: (a) Gaining unauthorized access to classified, export-controlled, or all communications security (COMSEC) (classified or unclassified) information in accordance with E.O. 12829 and DoD Instruction 8523.01, ·Communications Security· (available at

<http://www.dtic.mil/whs/directives/corres/pdf/852301p.pdf>). DoD FOCI procedures for access to unclassified COMSEC are set forth in National Security Agency Central Security Service (NSA/CSS) Policy Manual 3-16, Control of Communications Security Material (available to authorized users of SIPRNET at www.iad.nsa.smil.mil/resources/library/nsa_office_of_policy_section/pdf/NSA_CS_S_MAN-3-16_080505.pdf). (b) Adversely affecting the performance of classified contracts, in accordance with E.O. 12829 . (c) Undermining U.S. security and export controls, in accordance with E.O. 12829 . § 117.55 Responsibilities. (a) The Under Secretary of Defense for Intelligence (USD(I)) will, in accordance with DoD Directive 5143.01, Under Secretary of Defense for Intelligence (USD(I)) (available at <http://www.dtic.mil/whs/directives/corres/pdf/514301p.pdf>) and DoD Instruction 5220.22, National Industrial Security Program (see <http://www.dtic.mil/whs/directives/corres/pdf/522022p.pdf>): (1) Oversee policy and management of the NISP, to include FOCI matters. (2) Direct, administer, and oversee the FOCI provisions of the NISP to ensure that the program is efficient and consistently implemented. (3) Provide additional guidance regarding FOCI matters by memorandum as needed. (4) Coordinate with the Under Secretary of Defense for Policy (USD(P)) and the Under Secretary of Defense for Acquisition, Technology and Logistics (USD(AT&L)) on matters under their cognizance that affect the NISP consistent with paragraphs (c) and (d) of this section.

DFARS 252.204-7012 (Safeguarding Covered Defense Information and Cyber Incident Reporting) Core CUI protection clause requiring NIST SP 800-171 implementation, cyber incident reporting within 72 hours, and preservation of evidence. DFARS 252.204-7012 works in conjunction with the CMMC program. While 252.204-7012 establishes the contractual requirement, CMMC (under 32 CFR Part 170) provides the assessment framework. Phase 1 began November 10, 2025, with Phase 2 (C3PAO certification requirements) scheduled for November 10, 2026.

and to modify the heading to Access determination and modification. We also propose to modify this implementation specification to require a regulated entity to establish and implement written policies and procedures that, based on its access authorization policies, establish, document, review, and modify the access of each user and technology asset to specific components of the regulated entity's relevant electronic information systems. Such written policies and procedures would be required to be based upon the regulated entity's policies for authorizing access. Under this proposal, and consistent with the existing implementation specification, [575] the regulated entity would be required to establish standards for granting access to ePHI and relevant electronic information systems and provide formal authorization from the appropriate authority before granting access to ePHI or relevant electronic information systems. Regulated entities should regularly review personnel access to ePHI and relevant electronic information systems to ensure that access is still authorized and needed, and modify personnel access to ePHI and electronic information systems, as needed, based on review activities. The existing implementation specification for access authorization calls for the regulated entity to implement policies and procedures for granting access to ePHI, for example, through components of its information system. [576] The Department's proposal to revise this implementation specification would provide greater specificity than our existing requirements, and echo NIST guidance on this topic. Specifically, NIST guidance [577] describes the key steps for developing policies and procedures for granting access to ePHI as follows: Decide and document procedures for how access to ePHI would be granted to workforce members within the organization. Select the basis for restricting access to ePHI. Select an access control method (e.g., identity-based, role based, or other reasonable and appropriate means of access). Decide and document how access to ePHI would be granted for privileged functions. Ensure that there is a list of personnel with authority to approve user requests to access ePHI and systems with ePHI. Identify authorized users with access to ePHI, including data owners and data custodians. Consider whether multiple access control methods are needed to protect ePHI according to the results of the risk assessment. Determine whether direct access to ePHI would ever be appropriate for individuals external to the organization (e.g., business partners or patients seeking access to their own ePHI). Other questions that a regulated entity should consider when establishing such policies and procedures include: Have appropriate authorization and clearance procedures, as specified in the standard for workforce security, [578]

information security terms. - — Performed research and conducted outreach on standards, practices, and technologies to enable prompt and effective computer security incident handling and

coordination. - — Continued the successful collaboration with the Office of the Director of National Intelligence (ODNI), the - — ABA Federated Identity Management Legal (IdM Legal) Task Force - — American Bar Association (ABA), section on Science and Technology - — Cloud Security Alliance - — Forum of Incident Response and Security Teams (FIRST)

Revision 2, February 2020 (includes updates as of January 28, 2021) (NIST SP 800-171 R2); and selected requirements from the NIST SP 800-172, Enhanced Security Requirements for Protecting Controlled Unclassified Information: A Supplement to NIST Special Publication 800-171, February 2021 (NIST SP 800-172 Feb2021), as applicable (see table 1 to § 170.14(c)(4) for requirements, see § 170.2 for availability of NIST publications). (d) The CMMC Program balances the need to safeguard FCI and CUI and the requirement to share information appropriately with defense contractors in order to develop capabilities for the DoD. The CMMC Program is designed to ensure implementation of cybersecurity practices for defense contractors and to provide DoD with increased assurance that FCI and CUI information will be adequately safeguarded when residing on or transiting contractor information systems. (e) The CMMC Program creates no right or benefit, substantive or procedural, enforceable by law or in equity by any party against the United States, its departments, agencies, or entities, its officers, employees, or agents, or any other person. § 170.2 Incorporation by reference. Certain material is incorporated by reference into this part with the approval of the Director of the Federal Register under 5 U.S.C. 552(a) and 1 CFR part 51. Material approved for incorporation by reference (IBR) is available for inspection at the Department of Defense (DoD) and at the National Archives and Records Administration (NARA). Contact DoD online: <https://DoDcio.defense.gov/CMMC/>; email: osd.mc-alex.DoD-cio.mbx.cmmc-rule@mail.mil; or phone: (202) 770-9100. For information on the availability of this material at NARA, visit: www.archives.gov/federal-register/cfr/ibr-locations or email: fr.inspection@nara.gov. The material may be obtained from the following sources: (a) National Institute of Standards and Technology, U.S. Department of Commerce, 100 Bureau Drive, Gaithersburg, MD 20899; phone: (301) 975-8443; website: <https://csrc.nist.gov/publications/>. (1) FIPS PUB 200, Minimum Security Requirements for Federal Information and Information Systems, March 2006 (FIPS PUB 200 Mar2006); IBR approved for § 170.4(b). (2) FIPS PUB 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors, January 2022 (FIPS PUB 201-3 Jan2022); IBR approved for § 170.4(b). (3) SP 800-37, Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, Revision 2, December 2018 (NIST SP 800-37 R2); IBR approved for § 170.4(b). (4) SP 800-39, Managing Information Security Risk: Organization, Mission, and Information System View, March 2011 (NIST SP 800-39 Mar2011); IBR approved for § 170.4(b). (5) SP 800-53, Security and Privacy Controls for Information Systems and Organizations, Revision 5, September 2020 (includes updates as of December 10, 2020) (NIST SP 800-53 R5); IBR approved for § 170.4(b).

se enterprises and their subordinate organizations as well as systems owners to better identify, assess, and manage cybersecurity risks in the context of their broader mission and business objectives. 6 This document will help cybersecurity professionals understand what executives and corporate officers need to carry out enterprise risk management (ERM). This includes, but is not limited to, what data to collect, what analyses to perform, and how to consolidate and condition this discipline-specific risk information so that it provides useful inputs for ERM programs. This document will also help high-level executives and corporate officers understand the challenges that cybersecurity professionals face in providing them with relevant information. Because enterprise stakeholders are accustomed to receiving reports regarding many types of risk, guidance on cybersecurity that is consistent with these other risk categories will support well-crafted and actionable risk appetite and risk tolerance decisions and statements.

To ensure the integrity of the privacy and civil liberties process. The execution requires that information be provided in a free and open manner without fear of retribution or harassment in order to facilitate a just, thorough, and timely resolution of the complaint or inquiry. Disclosures from this system can enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying, or fabricating evidence or documents. In addition, disclosures can subject sources and witnesses to harassment or intimidation which may cause individuals not to seek redress for wrongs through privacy and civil liberties channels for fear of retribution or harassment. There is a clear need to protect national security information from inadvertent disclosure. § 310.29 Office of the Secretary of Defense (OSD) exemptions. (a) General information. The Secretary of Defense designates those Office of the Secretary of Defense

(OSD) systems of records which will be exempt from certain provisions of the Privacy Act. There are two types of exemptions, general and specific. The general exemption authorizes the exemption of a system of records from all but a few requirements of the Act. The specific exemption authorizes exemption of a system of records or portion thereof, from only a few specific requirements. If an OSD Component originates a new system of records for which it proposes an exemption, or if it proposes an additional or new exemption for an existing system of records, it shall submit the recommended exemption with the records system notice as outlined in § 311.6. No exemption of a system of records shall be considered automatic for all records in the system. The systems manager shall review each requested record and apply the exemptions only when this will serve significant and legitimate Government purpose. (b) General exemptions. The general exemption provided by 5 U.S.C. 552a(j)(2) may be invoked for protection of systems of records maintained by law enforcement activities. Certain functional records of such activities are not subject to access provisions of the Privacy Act of 1974. Records identifying criminal offenders and alleged offenders consisting of identifying data and notations of arrests, the type and disposition of criminal charges, sentencing, confinement, release, parole, and probation status of individuals are protected from disclosure. Other records and reports compiled during criminal investigations, as well as any other records developed at any stage of the criminal law enforcement process from arrest to indictment through the final release from parole supervision are excluded from release. (1) System identifier and name. DWHS P42.0, DPS Incident Reporting and Investigations Case Files. (i) Exemption. Portions of this system that fall within 5 U.S.C. 552a(j)(2) are exempt from the following provisions of 5 U.S.C. 552a

This rule proposes to amend the DFARS to implement changes to performance-based payment policies for DoD contracts by amending the policy on performance-based payments at DFARS 232.1001 and amending the clauses at DFARS 252.232-7012, Performance-Based Payments-Whole Contract Basis, and 252.232-7013, Performance-Based Payments-Deliverable Item Basis. This rule may benefit contractors who receive contract financing from the Government in the form of performance-based payments. Performance-based payments do not apply to: Payments under cost-reimbursement line-items; Contracts awarded under the authority of FAR part 12 or part 13; Contracts for architect-engineer services or construction, or for shipbuilding or ship repair, when the contract provides for progress payments based upon a percentage or stage of completion. Performance-based payments are tied to the achievement of specific, measurable events or accomplishments that are defined and valued in advance by the parties to the contract. Total performance-based payments cannot exceed 90 percent of the contract price. This rulemaking proposes to remove the DFARS restrictions that limit performance-based payments to amounts not greater than costs incurred up to the time of payment. If performance-based payments to the contractor based on the negotiated value of completed milestone events are allowed to exceed the total costs incurred up to the time of payment, the cost to the contractor of short-term borrowing will decrease and the cost to the Government of borrowing will increase. In addition, there is a minimal cost to offerors and the Government related to a new provision at DFARS 252.232-70XX, Performance-Based Payments-Representation, that requires each offeror responding to a solicitation that may result in a contract providing performance-based financing to represent whether the output of the offeror's accounting system is in compliance with Generally Accepted Accounting Principles, as evidenced by audited financial statements. DoD has performed a regulatory cost analysis on this rule. The following is a summary of the estimated public cost savings and Government costs in millions calculated in perpetuity in 2016 dollars at a 7-percent discount rate: Summary Public Government Total Present Value -\$53.971 \$27.338 -\$26.633 Annualized Costs -3.778 1.914 -1.864 Annualized Value Costs (as of 2016 if Year 1 is 2019) -3.084 1.562 -1.522 To access the complete Regulatory Cost Analysis, go to the Federal eRulemaking Portal at www.regulations.gov, search for "DFARS Case 2019-D002," click "Open Docket," and view "Supporting Documents." V. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563

). If a rule has a significant economic impact on a substantial number of small entities, the Regulatory Flexibility Act requires agencies to analyze regulatory options that would lessen the economic effect of the final rule on small entities. FDA finds that this final rule may have a significant economic impact on a substantial number of small entities. We estimate that more than 75 percent of all businesses covered by this final rule are small or very small. The undiscounted

per-facility costs for small and very small businesses are reported in the following table. Costs for learning and records redesign are one-time costs incurred in the first 2 years following publication of the final rule. Additional records maintenance costs are incurred each year following publication of the final rule beginning in the second year for large and small firms, and in the third year for very small firms. Table 23. Estimated Per Facility Recordkeeping Costs 21 CFR Section Costs 1.337, 1.345, and 1.352 (learning) \$120.00 1.337, 1.345, and 1.352 (records redesign) \$411.00 1.337, 1.345, and 1.352 (additional records maintenance) \$219.00 Comments Summary Comments cover topics such as reasons why staggering compliance dates will not achieve regulatory flexibility objectives, suggestions of regulatory alternatives that would achieve regulatory flexibility objectives, appeals to consider the cumulative costs of all four bioterrorism regulations together when considering the impact on small businesses, appeals for exclusion of certain categories of small businesses, as well as other general topics. The different categories of comments are summarized in the following paragraphs. (Comment 214) One comment finds the definition of "small business" uncertain and asks whether it is based on either the number of employees at a (printed page 71647) firm or the number of employees at a facility. (Response) The U.S. Small Business Administration (SBA) establishes small business definitions (or size standards) by industry (Ref. 28). The most common SBA size standard applicable to manufacturers covered by this final rule is 500 employees. Other pertinent SBA size standards include 100 employees for wholesale distributors, \$21.5 million in receipts for transporters, and \$6 million or \$23 million in receipts for retailers, depending on the type of store. After discussions with the SBA, we define a small business in the food industry as having more than 10 and fewer than 500 full-time equivalent employees, and we define very small firms as having 10 or fewer full-time equivalent employees. Firm size, rather than facility size, is used in the cost estimates for regulatory flexibility purposes whenever the data permit. For purpose of the compliance dates, the firm size governs. For purpose of the retail exclusion, the number of employees at the facility applies.

Form 1: DPA Security Profile, begins on page 13. Consult with the system manager, users, programmers, maintenance and procurement personnel, and any other associated persons to become familiar with the DPA and its operations before filling out this form. 1. Unsound installation or maintenance procedures; 3. Inadequate maintenance and inventory controls;

(W) 52.239-YY Federal Information Systems Using Non-Cloud Computing Services (DATE) (E.O. 14028 and 15 U.S.C. 278g-3e). (X) 52.239-XX Federal Information Systems Using Cloud Computing Services (DATE) (E.O. 14028). * * * * * 21. Amend section 52.213-4 by: a. Revising the date of the clause; b. Adding paragraphs (a)(1)(xii) and (xiii); and c. Revising the date of paragraph (a)(2)(vii). The additions and revisions read as follows: 52.213-4 Terms and Conditions-Simplified Acquisitions (Other Than Commercial Products and Commercial Services). * * * * * Terms and Conditions-Simplified Acquisitions (Other Than Commercial Products and Commercial Services) (DATE) * * * * * (a) * * * (1) * * * (xii) 52.239-YY Federal Information Systems Using Non-Cloud Computing Services (DATE) (E.O. 14028 and 15 U.S.C. 278g-3e). (xiii) 52.239-XX Federal Information Systems Using Cloud Computing Services (DATE) (E.O. 14028). (2) * * * (vii) 52.244-6, Subcontracts for Commercial Products and Commercial Services (DATE). * * * * * 22. Adding new sections 52.239-XX and 52.239-YY to read as follows: 52.239-XX Federal Information Systems Using Cloud Computing Services. As prescribed in 39.X04(b) insert the following clause: Federal Information Systems Using Cloud Computing Services (DATE) (a) Definitions. As used in this clause: Cloud computing means a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. Cloud computing is characterized by on-demand self-service, broad network access, resource pooling, rapid elasticity, and measured service; and includes service models such as software-as-a-service, infrastructure-as-a-service, and platform-as-a-service (NIST SP 800-145). Federal information system: (1) Means an information system (44 U.S.C. 3502(8)) used or operated by an agency, by a contractor of an agency, or by another organization, on behalf of an agency; (2) On behalf of an agency as used in this definition, means when a contractor uses or operates an information system or maintains or collects information for the purpose of processing, storing, or transmitting Government data, and those activities are not incidental to providing a service or product to the Government (32 CFR part 2002). Full access means, for all contractor information systems used in performance, or which support performance, of the contract: (1) Physical and electronic access to: (i) Contractor networks; (ii) Systems; (iii) Accounts with access to Government systems; (iv) Other infrastructure housed

on the same computer network; (printed page 68418) (v) Other infrastructure with a shared identity boundary or interconnection to the Government system; and (2) Provision of all requested Government data or Government-related data, including: (i) Images; (ii) Log files; (iii) Event information; and

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Contain, Exert) NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 REFERENCES 487

Keywords: Security Metrics; Computer Security, Security Evaluation While some movement toward quantitative metrics for IT system security exists, in practice, qualitative measures that reflect reasoned estimates of security by an evaluator are the norm. That is, measures of information system security properties are often based on an evaluator's expertise, intuition, and insight to induce an ordering, which is then quantified (e.g., 1=low, 2=medium, 3=high). Because of the subjectivity involved, some of the attributes sought in a good metric are not readily obtainable. For example, results in penetration testing or other methods of assessment that involve specialized skills are sometimes not repeatable, since they rely on the knowledge, talent, and experience of an individual evaluator, which can differ from other evaluators with respect to a property being measured. Many major efforts to measure or assess security have been attempted. They include the Trusted Computer System Evaluation Criteria (TCSEC) [DOD85], Information Technology Security Evaluation Criteria (ITSEC) [CEC91], Systems Security Engineering Capability Maturity Model (SSE-CMM) [ISS08], and Common Criteria [CCP06]. Each attempt has obtained only limited success.

From the NIST SP 800-172 Rev 3 Final Public Draft: The result is that malware targeted at specific software can only compromise a subset of the targeted systems, and a sufficient number continue to operate to complete the mission or business function. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025

From the NIST SP 800-172 Rev 3 Final Public Draft: [1] Executive Order 13556 (2010) Controlled Unclassified Information. (The White House, Washington, DC), DCPD-201000942, November 4, 2010. Available at <https://www.govinfo.gov/app/details/DCPD-201000942> [2] Executive Order 13526 (2009) Classified National Security Information. (The White House, Washington, DC), DCPD-200901022, December 29, 2009. Available at <https://www.govinfo.gov/app/details/DCPD-200901022> [3] Atomic Energy Act (P.L. 83-703), August 1954. Available at <https://www.govinfo.gov/app/details/STATUTE-68/STATUTE-68-Pg919> [4] National Archives and Records Administration (2019) Controlled Unclassified Information (CUI) Registry. Available at <https://www.archives.gov/cui> [5] 32 CFR Part 2002 (2016), Controlled Unclassified Information (CUI), September 2016. Available at a

Following analysis of a cyber incident, DC3/DCISE may provide information relevant to the potential or known compromise of DoD acquisition program information to the Office of the Secretary of Defense's Damage Assessment Management Office (OSD DAMO) for a cyber intrusion damage assessment. The Government may provide DIB participants with information regarding the damage assessment. (e) DIB participant attribution information. The Government acknowledges that information shared by the DIB participants under this program may include extremely sensitive proprietary, commercial, or operational information that is not customarily shared outside of the company, and that the unauthorized use or disclosure of such information could cause substantial competitive harm to the DIB participant that reported that information. The Government shall take reasonable steps to protect against the unauthorized use or release of such information (e.g., attribution information and other nonpublic information) received from a DIB participant or derived from such information provided by a DIB participant, including applicable procedures (see § 236.5(h)). The Government will restrict its internal use and disclosure of attribution information to only Government personnel and Government support contractors that are bound by appropriate confidentiality obligations and restrictions relating to the handling of this sensitive information and are engaged in lawfully authorized activities. (f) Non-attribution information. The Government may share non-attribution information that was provided by a DIB participant (or derived from information provided by a DIB participant) with other DIB participants in the DIB CS/IA program, and may share such information throughout the Government (including with Government support contractors that are bound by appropriate confidentiality obligations) for cyber security and information assurance purposes for the protection of Government information or information systems. (g) Electronic media. Electronic

media/files provided by DIB participants to DC3 under paragraphs (b), (c) and (d) of this section are maintained by the digital and multimedia forensics laboratory at DC3, which implements specialized handling procedures to maintain its accreditation as a digital and multimedia forensics laboratory. DC3 will maintain, control, and dispose of all electronic media/files provided by DIB participants to DC3 in accordance with established DoD policies and procedures. (h) Freedom of Information Act (FOIA). Agency records, which may include qualifying information received from non-federal entities, are subject to request under the Freedom of Information Act (5 U.S.C. 552) (FOIA), which is implemented in the Department of Defense by DoD Directive 5400.07 and DoD Regulation 5400.7-R (see 32 CFR Parts 285 and 286

IdAM is an important component of cloud computing security, and NIST publishes access control characteristics and general access control guidelines for various cloud service models. NIST also performs research and development regarding access control rules and methods. ## Access Control Policy Verification and Development Tools Traditional access control policy verification methods have capability and performance issues related to inaccuracy and complexity that is limited by applied technologies. For instance, model proof, test oracle, and data structure methods initially assume that the policy under verification is faultless unless the policy model cannot handle test cases. Thus, the challenge of the method is to compose test cases that can comprehensively discover all faults. Alternatively, a system simulation method requires translating the policy to a simulated system. The translation between systems may be difficult or impractical to implement if the policy logic is complicated or the number of policy rules is large. To answer these challenges, Machine Learning Method for Access Control Policy Verification (NISTIR 8360) proposes an efficient and straightforward method for access control policy verification by applying a classification algorithm of machine learning that does not require comprehensive test cases, oracle, or system translation but rather checks the logic of policy rules directly, making it more efficient and feasible compared to traditional methods.

(1) A record must exist and be in DoD possession and control at the time of the search to be subject to this part and the FOIA. The DoD Components are not obligated to create, compile, or obtain a record to satisfy a FOIA request. The DoD Components, however, may compile a new record when so doing would result in a more useful response to the requester or would be less burdensome to the agency than providing existing records. Any such compilation should be coordinated with and approved by the requester. The cost of creating or compiling such a record may not be charged to the requester unless the fee for creating the record is equal to or less than the fee that would be charged for providing the existing record. Fee assessments shall be in accordance with § 286.25.

(2) With regards to electronic data, the issue of whether records are actually created or merely extracted from an existing database is not always readily apparent. Consequently, when processing FOIA requests for electronic data where creation of a record, programming, or organizing in a particular format is questionable, if the Component has the capability to respond to the request, and the effort would be a business-as-usual approach then the request should be processed. (i) A business as usual approach exists when the Component has the capability to process the request without a significant expenditure of resources. If processing a request would cause a significant interference with the operation of the Component's automated information system, then it has a significant expenditure of resources. (ii) Creating computer programs and/or purchasing additional hardware to extract electronic mail that has been archived for the purpose of emergency retrieval normally are not viewed as business as usual. This is especially true if extensive resources are needed to complete the project. (iii) Creating a computer program that produces specific requested fields or records contained within a database normally is viewed as business as usual. The time to create this program shall be considered as computer operator [clarify] search time for fee assessment purposes and the requester may be assessed fees in accordance with § 286.25. (3) The DoD Components are not required to expend DoD funds to establish data links that provide real-time or near-real-time data to a FOIA requester. The Components are responsible to provide existing data downloaded to electronic media or printed in hard copy at the time the FOIA request is received or processed. If the information would serve the public interest or need, and is economically feasible, the Component may consider posting the information on the Internet. (g) Description of a requested record.

(a) For each requirement, except those exclusively for the acquisition of commercially available off-the-shelf items, the contracting officer shall obtain from the requiring activity an SF XXX that (1) Identifies what CUI is involved in the contract; (2) Specifies if and how the contractor

is to mark CUI involved in the contract (e.g., when the contractor is generating or developing the CUI, or when the purpose of the contract is to mark CUI); and (3) Conforms to 11.002(i).

(b)(1) If the contracting officer has a reason to question the information on the SF XXX, the contracting officer shall request that the requiring activity verify that the SF XXX is accurate.

(2) If the requiring activity has marked the 'Yes' box in Part A of SF XXX, the contracting officer shall incorporate the SF in the solicitation and contract and the clause at 52.204-XX, as prescribed at 4.403-7, to communicate requirements for safeguarding CUI during contract performance. (3) If the requiring activity has marked the 'No' box in Part A of SF XXX, the contracting officer shall include in the contract file a copy of the SF XXX and include in the solicitation and contract the clause at 52.204-YY, as prescribed at 4.403-7, to communicate requirements related to CUI should the contractor encounter suspected CUI during performance or the contract. (c) If the requiring activity states that there should be controlled access to the contents of the SF XXX or the SF XXX is marked as CUI itself, contracting officers shall follow agency procedures (printed page 4293) for safeguarding and disseminating the SF XXX. (d) If the contracting officer is notified or otherwise discovers that there is, or potentially could be CUI involved in the contract and it was not properly identified on an SF XXX, the contracting officer shall coordinate with the requiring activity to determine if the information is CUI. If the agency determines that the information is CUI, then the agency shall take the following steps: (1) If the agency wants the contractor to handle this kind of CUI during performance of the contract, the contracting officer shall: (i) Coordinate with the requiring activity to have the SF XXX updated; (ii) Modify the contract to incorporate the new SF XXX and, if CUI was not previously anticipated under the contract, to remove the clause at 52.204-YY and incorporate the clause at 52.204-XX; (iii) Consider any request for equitable adjustment submitted by the contractor, as appropriate; and (iv) Provide to the contractor marking instructions for the CUI. (2) If the agency does not want the contractor to handle this kind of CUI, the contracting officer shall coordinate with the requiring activity to address the CUI (e.g., retrieve the CUI) and shall convey such instructions to the contractor.

Specialized Assets) between the Level 2 and Level 3 assessments. As addressed in § 170.18, a condition to request a Level 3 certification assessment from DCMA DIBCAC is the receipt of a Final Level 2 (C3PAO) CMMC Status. The DoD considered, but declined, the recommendation to allow OSAs to simultaneously pursue Level 2 and Level 3 in one assessment. DoD must enforce CMMC requirements uniformly across the Defense Industrial Base for all contractors and subcontractors who process, store, or transmit CUI, regardless of an OSA's intended CMMC level. Permitting OSCs to seek combined CMMC Level 2 and 3 assessments would unfairly benefit only a subset of OSCs that were identified to meet CMMC Level 3 requirements. The rule has been updated to clarify that the OSC will be ineligible for additional contract awards that require a CMMC Level 3 certification assessment until such time as a valid (Conditional or Final) CMMC Level 3 (DIBCAC) CMMC Status is achieved for the information systems within the CMMC Assessment Scope. (printed page 83130) d. Scoring Methodology 1. CMMC Point Value System Comment: Multiple comments were received concerning the point values assigned to CMMC security requirements, their association to other frameworks, consistency between CMMC levels, and their use in POA&M eligibility determination. Numerous comments recommended that the CMMC Level 2 weighted point system where security requirements are valued as 1, 3, or 5 be modeled after the one point per requirement used in CMMC Level 3 scoring. Some also questioned why the CMMC Level 2 scoring structure was the same as the NIST SP 800-171 DoD Assessment Methodology (DODAM). Four comments recommended changes to the criteria for adding unimplemented security requirements to an Assessment POA&M. One comment noted that temporary deficiencies which are appropriately addressed in plans of action should be assessed as implemented. Some of the comments recommended not assigning point values to determine POA&M eligibility. Two other comments recommended dropping the NIST Basic and Derived security requirement designations and disassociating them from CMMC point values. Response:

223. 'Press release, 'HHS' Office for Civil Rights Settles Malicious Insider Cybersecurity Investigation for \$4.75 Million,' Office for Civil Rights, U.S. Department of Health and Human Services (Feb. 6, 2024), <https://www.hhs.gov/about/news/2024/02/06/hhs-office-civil-rights-settles-malicious-insider-cybersecurity-investigation.html> . Back to Citation 224. 'Press release, 'Snooping in Medical Records by Hospital Security Guards Leads to \$240,000 HIPAA Settlement,' Office for Civil Rights, U.S. Department of Health and Human Services (June 15, 2023), <https://www.hhs.gov/about/news/2023/06/15/snooping-medical-records-by-hospital-security-guards-leads-240-000-hipaa-settlement.html> . Back to Citation 225. 'Remediation and Guidance Hub: Falcon Content Update for Windows Hosts,' CrowdStrike, <https://www.crowdstrike.com/falcon->

content-update-remediation-and-guidance-hub/. . Back to Citation 226. . See .Data Integrity: Detecting and Responding to Ransomware and Other Destructive Events,. NIST Special Publication 1800-26A, National Institute of Standards and Technology, U.S. Department of Commerce, p. 1 (Dec. 2020), <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1800-26.pdf> . Back to Citation 227. .Likely eCrime Actor Uses Filenames Capitalizing on July 19, 2024, Falcon Sensor Content Issues in Operation Targeting LATAM-Based CrowdStrike Customers,. CrowdStrike Blog (July 20, 2024), <https://www.crowdstrike.com/blog/likely-ecrime-actor-capitalizing-on-falcon-sensor-issues/> . Back to Citation 228. .Letter from NCVHS Chair Jacki Monson (2023), *supra* note 123, p. 2 (explaining that NCVHS conducted an inquiry into whether compliance with the Security Rule had improved since the Department released the results of its 2016-2017 audit of selected provisions of the Security Rule and found that .not much had changed.); .Muddling through cybersecurity: Insights from the U.S. healthcare industry,. *supra* note 116, p. 540 (.There is enough evidence to suggest that U.S. healthcare organizations lack a deliberate, organized, and comprehensive cyber-resilience strategy.). Back to Citation 229. . See Susan Kiser, et al., .Ransomware: Healthcare Industry at Risk,. *Journal of Business and Accounting*, p. 65-66 (Fall 2021); Meghan Hufstader Gabriel, .Data Breach Locations, Types, and Associated Characteristics Among US Hospitals,. *American Journal of Managed Care*, p. 78 (Feb. 2018); .Is the HIPAA Security Rule Enough to Protect Electronic Personal Health Information (PHI) in the Cyber Age? . *supra* note 207, p. 20-23. Back to Citation 230. .Chris Hayhurst, .On Guard: Staying Vigilant Against Medical Device Vulnerabilities,. *Biomedical Instrumentation & Technology*, Volume 54, Issue 3, p. 169 (May/June 2020); .Report on Improving Cybersecurity In The Health Care Industry,. *supra* note 117, p. 2. Back to Citation 231. .2021 HIMSS Healthcare Cybersecurity Survey,. *Healthcare Information and Management Systems Society*, p. 18 (Jan. 28, 2022),

(1) The appeal with all supporting materials both that furnished the individual and that contained in Component records is provided to the reviewing official; and (2) If the appeal is denied completely or in part, the individual is notified in writing by the reviewing official that: (i) The appeal has been denied and the specific reason and authority for the denial; (ii) The individual may file a statement of disagreement with the appropriate authority and the procedures for filing this statement; (iii) If filed properly, the statement of disagreement shall be included in the records, furnished to all future recipients of the records, and provided to all prior recipients of the disputed records who are known to hold the record; and (iv) The individual may seek a judicial review of the decision not to amend. (3) If the record is amended, ensure: (i) The requester is notified promptly of the decision; (ii) All prior known recipients of the records who are known to be retaining the record are notified of the decision and the specific nature of the amendment (see (l) of this Section); and (iii) The requester is notified which DoD Components and Federal agencies have been told of the amendment. (4) Process all appeals within 30 days unless the appeal authority determines that a fair review cannot be made within this time limit. If additional time is required for the appeal, notify the requester, in writing, of the delay, the reason for the delay, and when he or she may expect a final decision on the (printed page 18770) appeal. Document fully all requirements for additional time in the Privacy Case File. (See paragraph (p) of this section.) (l) Denying amendment of OPM records held by the DoD Components. (1) The records in all systems of records controlled by the OPM Government-wide system notices are technically only temporarily in the custody of the Department of Defense. (2) All requests for amendment of these records must be processed in accordance with 5 CFR part 297 . The Component denial authority may deny a request. However, when an amendment request is denied, the DoD Component shall advise the individual that his or her appeal must be directed to the Assistant Director for Workforce Information, Personnel Systems and Oversight Group, U.S. Office of Personnel Management, 1900 E Street, Washington, DC 20415 in accordance with the procedures of 5 CFR 297 . (m) Statements of disagreement submitted by individuals. (1) If the appellate authority refuses to amend the record as requested, the individual may submit a concise statement of disagreement setting forth his or her reasons for disagreeing with the decision not to amend. (2) If an individual chooses to file a statement of disagreement, annotate the record to indicate that the statement has been filed (see paragraph (n) of this section).

Training that provides information as to the application of specific provisions of this part to specialized areas of job performance. Personnel of particular concern include, but are not limited to, personnel specialists, finance officers, DOD personnel who may be expected to deal with the news media or the public, special investigators, paperwork managers, individuals working with medical and security records, records managers, computer systems development personnel, computer systems

operations personnel, statisticians dealing with personal data and program evaluations, contractors and anyone responsible for implementing or carrying out functions under this part. Specialized training should be provided on a periodic basis; and (iii) Managerial training. Training designed to identify for responsible managers (such as senior system managers, Denial Authorities, and functional managers described in this section) issues that they should consider when making management decisions affected by the Privacy Act Program. (b) Training tools. Helpful resources include-

- (1) Privacy Act training slides for Major Commands and Privacy Act Officers: Contact the DA FOIA/P Office, or slides can be accessed at the Web site <https://www.rmda.belvoir.army.mil/rmdaxml/rmda/FPHomePage.asp>.
- (2) The DOJ Freedom of Information Act Guide and Privacy Act Overview: The U.S. Department of Justice, Executive Office for United States Attorneys, Office of Legal Education, 600 E. Street, NW., Room 7600, Washington, DC 20530, or training programs can be accessed at the Web site www.usdoj.gov/usa/ea/ole.html.

§ 505.9 Reporting requirements. The Department of the Army will submit reports, consistent with the requirements of DOD 5400.11-R, OMB Circular A-130, and as otherwise directed by the Defense Privacy Office. Contact the DA FOIA/P Office for further guidance regarding reporting requirements.

§ 505.10 Use and establishment of exemptions. (a) Three types of exemptions. (1) There are three types of exemptions applicable to an individual's right to access permitted by the Privacy Act. They are the Special, General, and Specific exemptions. (2) Special exemption (d)(5)-Relieves systems of records from the access provision of the Privacy Act only. This exemption applies to information compiled in reasonable anticipation of a civil action or proceeding. (3) General exemption (j)(2)-Relieves systems of records from most requirements of the Act. Only Army activities actually engaged in the enforcement of criminal laws as their primary function may claim this exemption. (4) Specific exemptions (k)(1)-(k)(7)-Relieves systems of records from only a few provisions of the Act.

[WHAnnouncement] White House (2023) BidenHarris Administration Announces Cybersecurity Labeling Program for Smart Devices to Protect American Consumers. (White House, Washington, DC). <https://www.whitehouse.gov/briefing-room/statementsreleases/2023/07/18/biden-harris-administration-announces-cybersecurity-labelingprogram-for-smart-devices-to-protect-american-consumers/> [IR8425] Fagan M, Megas KN, Watrobski P, Marron J, Cuthill B (2022) Profile of the IoT Core Baseline for Consumer IoT Products. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Interagency or Internal Report (IR) NIST IR 8425. <https://doi.org/10.6028/NIST.IR.8425> [BBF] Walls, J, Editor (2022) Functional Requirements for Broadband Residential Gateway Devices. (Broadband Forum, Fremont, CA), Technical Report (TR) 124, Issue 8. <https://www.broadband-forum.org/pdfs/tr-124-8-0-0.pdf> [CableLabs] CableLabs Security (2021) Gateway Device Security Best Common Practices. (CableLabs, Louisville, CO), CL-GL-GDS-BCP-V01-211007. <https://community.cablelabs.com/wiki/plugins/servlet/cablelabs/alfresco/download?id=1209eea3-bd81-40cb-9a18-21bd6cfd80d> [BSI] Federal Office for Information Security (2023) Secure Broadband Router: Requirements for Secure Broadband Routers. (Federal Office for Information Security, Bonn, Germany), BSI Technical Report (TR) 03148. <https://www.bsi.bund.de/EN/Themen/Unternehmen-undOrganisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Themasortiert/tr03148/tr-03148.html> [IMDA] Info-communications Media Development Authority of Singapore (2020) Security Requirements for Residential Gateways. (Info-communications Media Development Authority, Singapore), IMDA Technical Specification (TS) RG-SEC. <https://www.imda.gov.sg/-/media/imda/files/regulation-licensing-and-consultations/ictstandards/telecommunication-standards/radio-comms/imda-ts-rg-sec.pdf> [SP800-193] Regenscheid, AR (2018) Platform Firmware Resiliency Guidelines.

One comment asks what action FDA can take against foreign companies that do not establish and maintain the records required under section 306 of the Bioterrorism Act. A few comments state that the fact that section 306 of the Bioterrorism Act does not provide any mechanisms for enforcement of the recordkeeping and records access requirements against foreign persons supports the position that Congress did not intend that section to apply to foreign entities. (Response) Because FDA has decided, for policy reasons, to exempt foreign facilities that do not manufacture, process, pack, distribute, hold, or import food in the United States from the requirements of the rule, FDA does not need to decide this jurisdictional issue. FDA is exempting all foreign persons (except for foreign persons who transport food in the United States) from the final regulation because FDA does not believe such records would be needed. Much of this information is available to the Secretary from facilities required to provide prior notice under part 1, subpart I. FDA intends to work with the competent authorities in foreign countries to access records during public health emergencies to obtain additional information, if necessary. However, the final rule explicitly provides that

persons who transport food in the United States are subject to subpart J of this final rule. (Comment 26) One comment questions FDA's determination that it can perform its Bioterrorism Act (printed page 71573) mission of tracking shipments by exempting Mexican and Canadian motor carriers from the recordkeeping requirements while requiring U.S. motor carriers to comply with the recordkeeping requirements. The comment notes that, based on CBP figures for Mexico-domiciled carriers, referenced in the 'Economic Impact Estimates' section of the proposed rule, 63,000 out of 80,000 carriers operating across the southern border are Mexico-domiciled. The comment points out that, therefore, the majority of cross-border FDA-regulated shipments at the southern border may be exempt from the requirements of the regulation. (Response) FDA agrees. The final rule provides that foreign persons who transport food in the United States are subject to this final rule. A 'transporter' is now defined as: * * * a person who has possession, custody, or control of an article of food in the United States for the sole purpose of transporting the food, whether by road, trail, water, or air. Transporter also includes a foreign person that transports food in the United States, regardless of whether the foreign person has possession, custody, or control of that food for the sole purpose of transporting that food.* * * Thus, even if a foreign manufacturing facility transports its own manufactured food into the United States, it is considered a 'transporter' under subpart J of this final rule and must comply with the requirements applicable to transporters.

As discussed above in greater detail, physical safeguards encompass the physical measures, and related policies and procedures, to protect relevant electronic information systems and related buildings and equipment from natural and environmental hazards, and unauthorized intrusion. [633] The standard for facility access controls applies to protect the physical premises, while the standards for workstation use, workstation security, and device and media controls are aimed at protecting the electronic information systems and electronic media that create, receive, maintain, or transmit ePHI or that otherwise affect its confidentiality, integrity, and availability. The standard for facility access controls at 45 CFR 164.310(a)(1) requires a regulated entity to implement policies and procedures that limit physical access to electronic information systems and facilities that contain those systems. Section 164.310(a)(1) also requires a regulated entity to ensure its policies and procedures allow persons who are properly authorized to access its facilities. Under 45 CFR 164.310(a)(2) , a regulated entity must implement the standard for facility access controls in accordance with four implementation specifications. The implementation specification for contingency operations addresses the establishment (and implementation as needed) of procedures that allow for facility access in support of the restoration of lost data under a disaster recovery plan and emergency mode operations. [634] Section 164.310(a)(2)(ii) contains the specification for a facility security plan and addresses the implementation of policies and procedures to safeguard facilities and equipment in such facilities from unauthorized physical access, tampering, and theft. The implementation of procedures for role-based access control, including for visitors and for access to software programs for testing and revision is addressed in 45 CFR 164.310(a)(2)(iii) , while 45 CFR 164.310(a)(2)(iv) addresses the implementation of policies and procedures for the documentation of repairs and modifications to physical security components of a facility, such as hardware, walls, doors, and locks. Section 164.310(b) requires a regulated entity to implement policies and procedures specifying proper workstation functions, the manner in which those functions are to be performed, and the physical attributes of the environment for where specific workstations or classes of workstation used for accessing ePHI. [635] This standard is not accompanied by standalone implementation specifications, compared to the standards for facility access controls at 45 CFR 164.310(a) and device and media controls at 45 CFR 164.310(d)

AC.L2-3.1.6 · Non-Privileged Account Use CMMC Assessment Guide · Level 2 | Version 2.13 28
 system. System administrators and users with privileged accounts must be trained not to use their privileged accounts for everyday tasks, such as browsing the internet or connecting unnecessarily to other systems or services. Example You are logged in using your privileged account and you need to look up how to reset a non- functioning application which processes CUI . You should log on to another computer with your non-privileged account before you connect to the web and start searching for the reset information [b]. That way, if your account is compromised during the search, it will be your regular user account rather than an account with elevated privileges. Potential Assessment Considerations · Are nonsecurity functions and non-privileged roles defined [a,b]? · Is it required that nonsecurity functions only be accessed with the use of non- privileged accounts? How is this verified [b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.1.6

means an entity's senior management official (SMO), facility security officer (FSO), insider threat program senior official (ITPSO), and all other entity officials who either hold majority interest or stock in, or have (printed page 83317) direct or indirect authority to influence or decide issues affecting the management or operations of, the entity or classified contract performance. L access authorization means an access determination that is granted by DOE or NRC based on a Tier 3 or successor background investigation as set forth in applicable national-level requirements and DOE directives. Within DOE and NRC, an L access authorization permits an individual who has an official need to know to access Confidential Restricted Data, Secret and Confidential Formerly Restricted Data, Secret and Confidential Transclassified Foreign Nuclear Information, or Secret and Confidential National Security Information, required in the performance of official duties. An L access authorization determination is required for individuals with a need to know outside of DOE, NRC, DoD, and in limited cases NASA, to access Confidential Restricted Data. LAA means security access authorization to CONFIDENTIAL or SECRET information granted to non-U.S. citizens requiring only limited access in the course of their regular duties. Material means any product or substance on or in which information is embodied. Matter means anything in physical form that contains or reveals classified information. Media means physical devices or writing surfaces including but not limited to, magnetic tapes, optical disks, magnetic disks, large-scale integration memory chips, and printouts (but not including display media) onto which information is recorded, stored, or printed within an information system. MFO means a legal entity (single proprietorship, partnership, association, trust, or corporation) composed of two or more entities (facilities). National of the United States means a person who owes permanent allegiance to the United States. All U.S. citizens are U.S. nationals; however, not all U.S. nationals are U.S. citizens (for example, persons born in American Samoa or Swains Island). NATO information means information bearing NATO markings, indicating the information is the property of NATO, access to which is limited to representatives of NATO and its member nations unless NATO authority has been obtained to release outside of NATO. NATO visits means visits by personnel representing a NATO entity and relating to NATO contracts and programs. Need-to-know means a determination made by an authorized holder of classified information that a prospective recipient has a requirement for access to, knowledge of, or possession of the classified information to perform tasks or services essential to the fulfillment of a classified contract or program. Network means a system of two or more information systems that can exchange data or information. NNPI

From the NIST SP 800-172 Rev 3 Final Public Draft: The type of security requirement is noted in the discussion section of each requirement. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 Appropriately scoping security requirements is an important factor in determining protection-234

, records concerning matters that another statute specifically exempts from disclosure are exempt under this exemption. This exemption allows for the withholding of information because its release is prohibited by another statute only if one of two disjunctive requirements is met: The statute requires that the information be withheld from the public in such a manner as to leave no discretion on the issue, or the statute establishes particular criteria for withholding or refers to particular types of matters to be withheld. The DFOIPO maintains on its Web site a list of Exemption 3 statutes used within the Department of Defense. (d) Exemption 4. Pursuant to 5 U.S.C. 552(b)(4) , records containing trade secrets or commercial or financial information received by the DoD Component from a person or organization outside the Government are exempt from release. Information protected by this exemption must be trade secrets or commercial or financial records, the disclosure of which is likely to cause substantial harm to the competitive position of the submitter providing the information; impair the Government's ability to obtain necessary information in the future; or impair some other legitimate Government interest. If the information qualifies as Exemption 4 information, there is no discretion in its release. (1) Examples of information protected by Exemption 4 include: (i) Commercial or financial information received in confidence in connection with loans, bids, contracts, or proposals. (ii) Statistical data and commercial or financial information concerning contract performance, income, profits, losses, and expenditures. (iii) Personal statements given in the course of inspections, investigations, or audits. (iv) Financial data provided by private employers in connection with locality wage surveys that are used to fix and adjust pay schedules applicable to the prevailing wage rate of employees within the Department of Defense. (v) Scientific and manufacturing processes or developments concerning technical or scientific data or other information submitted with an application for a research grant, or with a report while research is in progress. (vi) Technical or scientific data developed by a contractor

or subcontractor exclusively at private expense, or developed in part with Federal funds and in part at private expense. The contractor or subcontractor must retain legitimate proprietary interests in such data in accordance with 10 U.S.C. 2320-2321 and DoD Federal Acquisition Regulation Supplement, Chapter 2 of title 48 Code of Federal Regulations, Subpart 227.71-227.72. Technical data developed exclusively with Federal funds may be withheld under Exemption 3, if it meets the criteria of 10 U.S.C. 130 and 48 CFR. See § 286.14. (vii) Copyrighted information under 17 U.S.C. 106.

(ii) Efforts by any individual, regardless of nationality, to elicit information from an employee determined eligible for access to classified information, and any contact which suggests the employee may be the target of an attempted exploitation by an intelligence service of another country. See SEAD 3 for specific information to be reported. (3) Change in status of employees determined eligible for access to classified information. Contractors will report by means of the CSA-designated reporting mechanism information pertaining to changes in status of employees determined eligible for access to classified information such as: (i) Death. (ii) Change in name. (iii) Termination of employment. (iv) Change in citizenship. (4) Citizenship by naturalization. Contractors will report if a non-U.S. citizen employee granted an LAA becomes a citizen through naturalization. The report will include: (i) City, county, and state where naturalized. (ii) Date naturalized. (iii) Court. (iv) Certificate number. (5) Employees desiring not to be processed for a national security eligibility determination or not to perform classified work. Contractors will report instances when an employee no longer wishes to be processed for a determination of eligibility for access to classified information or to continue having access to classified information, and the reason for that request. (6) Classified information nondisclosure agreement (NDA). Contractors will report the refusal by an employee to sign the SF 312, Classified Information Nondisclosure Agreement, (available at: <https://www.gsa.gov/cdnstatic/SF312-13.pdf?forceDownload=1>) or other approved NDA. (7) Changed conditions affecting the contractor's eligibility for access to classified information. Contractors are required to report certain events that affect the status of the entity eligibility determination (e.g., FCL), affect the status of an employee's PCL, may indicate an employee poses an insider threat, affect the proper safeguarding of classified information, or indicate classified information has been lost or compromised, including: (i) Change of ownership or control of the contractor, including stock transfers that affect control of the entity. (ii) Change of operating name or address of the entity or any of its locations determined eligible for access to classified information. (iii) Any change to the information previously submitted for KMP including, as appropriate, the names of the individuals the contractor is replacing. A new complete KMP listing need be submitted only at the discretion of the contractor or when requested by the CSA. The contractor will provide a statement indicating: (A) Whether the new KMP are cleared for access to classified information, and if cleared, to what level they are cleared and when they were cleared, their dates and places of birth, social security numbers, and citizenship. (B) Whether they have been excluded from access to classified information in accordance with § 117.7(b)(5)(ii).

Internal system clocks are used to generate time stamps, which include date and time. Time is expressed in Coordinated Universal Time (UTC), a modern continuation of Greenwich Mean Time (GMT), or local time with an offset from UTC. The granularity of time measurements refers to the degree of synchronization between system clocks and reference clocks, for example, clocks synchronizing within hundreds of milliseconds or within tens of milliseconds. Organizations may define different time granularities for different system components. Time service can also be critical to other security capabilities such as access control and identification and authentication, depending on the nature of the mechanisms 74 NIST SP 800-171A, pp. 23-24. 75 NIST SP 800-171 Rev. 2, p. 19.

(Response) FDA does not agree that much of the information required under this recordkeeping rule is already required under the registration interim final rule. Information required under the registration interim final rule pertains to the facility itself, including information about the general food product categories that the facility manufactures/processes, packs, or holds. Information that this final rule mandates be established and maintained in records is information pertaining to food that will assist FDA in identifying the immediate previous sources and the immediate subsequent recipients of all food that is received and released by a person. In addition, to complete the tracing investigation, the identity of the transporters who transported the food to and from the sources and recipients is required, which is not covered by the facility registration. Moreover, the scope of section 305 of the Bioterrorism Act (registration) is not as broad as section

306 of the Bioterrorism Act (establishment and maintenance of records). Specifically, registration applies only to facilities that manufacture, process, pack, or hold food for consumption for humans or animals in the United States. Recordkeeping applies to these facilities, as well as those who transport, distribute, receive, or import food. Recordkeeping also applies to all food regardless of whether it will be consumed in the United States or exported. However, FDA has deleted the requirement that persons subject to subpart J of this final rule identify a responsible individual in the records. Instead, for those facilities required to register under part 1, subpart H, FDA will use the emergency contact telephone number provided by those facilities. For other facilities, FDA does not believe requiring such facilities to provide an emergency contact telephone number is needed to assist the Secretary to identify the immediate previous sources and immediate subsequent recipients of food, since that telephone number would be contained in the very records FDA would be seeking assistance in locating. (Comment 89) One comment states that it is unreasonable to require nontransporters to have a record of the intermediate transporters, i.e., transporters who do not have direct contact with the nontransporters. (Response) Neither the proposed rule nor the final rule requires nontransporters to establish and maintain records identifying intermediate transporters. With respect to transportation records, § 1.337(a)(6) of this final rule only requires nontransporters to establish and maintain records of the transporter that brought the food to them. Similarly, § 1.345(a)(6) of this final rule only requires nontransporters to establish and maintain records of the transporter that took the food from them. The transporters are required to keep records that identify intermediate transporters.

Disclosure from a system of records maintained by a Component may be made to a congressional office from the record of an individual in response to an inquiry from the congressional office made at the request of that individual. E. Routine Use-Private Relief Legislation Relevant information contained in all systems of records of the Department of Defense published on or before August 22, 1975, may be disclosed to the Office of Management and Budget in connection with the review of private relief legislation as set forth in OMB Circular A-19 at any stage of the legislative coordination and clearance process as set forth in that circular. F. Routine Use-Disclosures Required By International Agreements A record from a system of records maintained by a Component may be disclosed to foreign law enforcement, security, investigatory, or administrative authorities to comply with requirements imposed by, or to claim rights conferred in, international agreements and arrangements, including those regulating the stationing and status in foreign countries of Department of Defense military and civilian personnel. G. Routine Use-Disclosure to State and Local Taxing Authorities Any information normally contained in Internal Revenue Service (IRS) Form W-2 which is maintained in a record from a system of records maintained by a Component may be disclosed to State and local taxing authorities with which the Secretary of the Treasury has entered into agreements under 5 U.S.C., sections 5516, 5517, 5520, and only to those State and local taxing authorities for which an employee or military member is or was subject to tax regardless of whether tax is or was withheld. This routine use is in accordance with Treasury Fiscal Requirements Manual Bulletin No. 76-07. H. Routine Use-Disclosure to the Office of Personnel Management A record from a system of records subject to the Privacy Act and maintained by a Component may be disclosed to the Office of Personnel Management (OPM) concerning information on pay and leave, benefits, retirement reductions, and any other information necessary for the OPM to carry out its legally authorized government-wide personnel management functions and studies. I. Routine Use-Disclosure to the Department of Justice for Litigation A record from a system of records maintained by a Component may be disclosed as a routine use to any component of the Department of Justice for the purpose of representing the Department of Defense, or any officer, employee or member of the Department in pending or potential litigation to which the record is pertinent. J. Routine Use-Disclosure to Military Banking Facilities

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Department of the Army [Docket No. USA-2006-0011] 32 CFR Part 505 RIN 0702-AA53 AGENCY: Department of the Army, DoD. ACTION: Final rule. SUMMARY: The Department of the Army is updating policies and responsibilities for the Army Privacy Program, which implements the Privacy Act of 1974, by showing organizational realignments and by revising referenced statutory and regulatory authority, such as the Health Insurance Portability and

Accountability Act and E-Government Act of 2002. This rule finalizes the proposed rule that was published in the Federal Register on April 25, 2006. DATES: Effective Date: September 11, 2006. ADDRESSES: U.S. Army Records Management and Declassification Agency, Freedom of Information and Privacy Office, 7701 Telegraph Road, Casey Bldg., Suite 144, Alexandria, VA 22315-3905. FOR FURTHER INFORMATION CONTACT: Ms. Janice Thornton at (703) 428-6503. SUPPLEMENTARY INFORMATION: A. Background In the April 25, 2006, issue of the Federal Register (71 FR 24494), the Department of the Army issued a proposed rule to revise 32 CFR part 505 . It incorporates Privacy Act policy objectives to include (1) restricting disclosure of personally identifiable records maintained; (2) to grant individuals rights of access to agency records maintained on themselves; (3) to grant individuals the right to seek amendment of agency records maintained on themselves upon a showing that the records are not accurate, relevant, timely, or complete; and (4) to establish practices ensuring the Army is complying with statutory norms for collection, maintenance, and dissemination of records. The Department of the Army received two comments from one commenter. No substantive changes were requested or made; however, the proposed changes were accepted and made to the final rule. The commenter expressed concern on §-505-2(e) titled ·Nomination of individuals when personal information * * *. It was changed to read ·Notification of individuals when personal information * * *. The other concern was in §-505.2(a)(2), suggestion was made to clarify the section by incorporating the DoD 6025.18-R, Privacy of Individually Identifiable Health Information in DoD Health Care Programs, language. The proposed §-505.2 (a)(3) through §-505.2(a)(13) was redesignated as §-505.2(a) (4) through §-505.2(a)(14) and a new §-505.2(a)(3) was added. B. Executive Order 12866 (Regulatory Planning and Review)

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Health and Human Services Notice is hereby given that I have delegated to the Assistant Deputy Secretary for National Security within the Office of the Secretary (OS), Immediate Office of the Secretary (IOS), Office of National Security (ONS), the authorities vested in me as the Secretary of Health and Human Services for managing the Controlled Unclassified Information Program under Executive Order 13556 , now and hereafter. This authority may be redelegated, but only within ONS. Exercise of this authority shall be in accordance with established policies, procedures, guidelines, and regulations as prescribed by the E.O. 13556 and 32 CFR part 2002 ·Controlled Unclassified Information.· This delegation of authority is effective immediately upon signature. Dated: March 15, 2023. Xavier Becerra, Secretary. [FR Doc. 2023-05637 Filed 3-17-23; 8:45 am] BILLING CODE P

AU.L2-3.3.1 · System Auditing CMMC Assessment Guide · Level 2 | Version 2.13 72 Audit and Accountability (AU) AU.L2-3.3.1 · SYSTEM AUDITING Create and retain system audit logs and records to the extent needed to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity. ASSESSMENT OBJECTIVES [NIST SP 800-171A]62 Determine if: [a] audit logs needed (i.e., event types to be logged) to enable the monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity are specified; [b] the content of audit records needed to support monitoring, analysis, investigation, and reporting of unlawful or unauthorized system activity is defined; [c] audit records are created (generated); [d] audit records, once created, contain the defined content; [e] retention requirements for audit records are defined; and [f] audit records are retained as defined. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]

note 632 (·These days numerous commercial merchants are intermingling with hospitals as well as healthcare providers to establish healthcare-based cloud computing networks.·); see also id. (·[. . .] Microsoft, Google and Amazon have instantly realized that the majority of hospitals will not continue working with servers that are privately owned as well as controlled.·); ·Increase in health-care cyberattacks affecting patients with cancer,· supra note 180 (In 2021, an attack against oncology services targeted data stored in cloud-based systems and affected patients in several States.). Back to Citation 833. ·Nicole Perlroth, et al., ·Cyberattack Hits Ukraine Then Spreads Internationally,· The New York Times (June 27, 2017) (discussing a worldwide ransomware attack in 2017), <https://www.nytimes.com/2017/06/27/technology/ransomware-hackers.html> . Back to Citation 834. · See 68 FR 8334 (Feb. 20, 2003). Back to Citation 835. · See 78

FR 5566 (Jan. 25, 2013). Back to Citation 836. ·A subcontractor of a business associate also would be required to make such report to the business associate. See 45 CFR 164.314(a)(2)(iii) (applying the requirements in paragraphs (a)(2)(i) and (ii) to business associate agreements between business associates and subcontractors in the same manner as they apply to business associate agreements between covered entities and business associates). Back to Citation 837. · See 45 CFR 164.410 . Back to Citation 838. ·Saheed Oladimeji, et al., ·SolarWinds hack explained: Everything you need to know,· TechTarget (Nov. 3, 2023) (SolarWinds is a software company and one of its products that was part of a supply chain attack is an IT performance monitoring system that had privileged access to IT systems.), <https://www.techtarget.com/·whatis/·feature/·SolarWinds-hack-explained-Everything-you-need-to-know> . Back to Citation 839. ·As discussed in greater detail above, the Department is proposing to renumber the standard for the contingency plan as 45 CFR 164.308(a)(13) and to require a written contingency plan for responding to an emergency or other occurrence that adversely affects relevant electronic information systems, as opposed to the current standard which applies when the emergency or other occurrence damages information systems that contain ePHI. Back to Citation 840. ·Proposed 45 CFR 164.314(a)(2)(i)(C) and (D) ; ·Cybersecurity Performance Goals,· supra note 18. Back to Citation 841. ·Proposed 45 CFR 164.308(a)(13)(i) . Back to Citation 842. ·The ping command is a network diagnostic, and firewalls often block incoming pings to prevent attackers from learning more about the organization's network. Karen Scarfone, et al., ·Guidelines on Firewalls and Firewall Policy,· NIST Special Publication 800-41, Revision 1, National Institute of Standards and Technology, U.S. Department of Commerce, p. 31 (Sept. 2009), <https://doi.org/·10.6028/·NIST.SP.800-41r1> . Back to Citation 843. 45 CFR 164.314(a)(2)(i)(C) . Back to Citation

(ii) During working hours when an open storage area is unattended, admittance to the area must be controlled by locked entrances and exits secured by GSA-approved pedestrian door locking hardware (FF-L-2890C), ·Federal Specification Lock Extension,· or CSA approved deadbolts or emergency exit hardware on any secondary doors. * * * * * (c) Storage. Contractors will store classified information and material in General Services Administration (GSA)-approved security containers, vaults built to Federal Standard 832, or an open storage area constructed in accordance with 32 CFR 2001.53 . The CSA may grant self-approval to the FSO for open storage area approvals, provided the FSO meets specified qualification criteria as determined by the CSA. In the instance that an open storage area has a false ceiling or raised floor, contractors shall develop and implement procedures to ensure their structural integrity in accordance with CSA provided guidance. Nothing in 32 CFR part 2001 , should be construed to contradict or inhibit compliance with local laws or building codes, but the contractor will notify the applicable CSA if there are any conflicting issues that would inhibit compliance. Contractors will store classified material in accordance with the specific sections of 32 CFR 2001.43 : * * * * * (d) * * * (3) * * * (i) * * * (A) If after a thorough inspection of the facility perimeter with no damage to the facility visible, the alarm system resets and remains in the secure condition, then entrance into the area is not required and an initial response team may consist of uncleared personnel. * * * * * (e) * * * (1) * * *

(ii) An information management system to protect and control the classified information in their possession regardless of media, to include information processed and stored on information systems with an authorization to operate by an applicable CSA, otherwise referred to as an authorized information system. (2) Top secret information. Unless otherwise directed by the applicable CSA, the contractor will establish the following additional controls: * * * * * (viii) When TOP SECRET information and material is generated or stored on authorized information systems, contractors will establish controls for TOP SECRET information and material to validate procedures are in place to address accountability, need to know, and retention, e.g., demonstrating that TOP SECRET material stored in an electronic format on an authorized information system does not need to be individually numbered in series. These controls are in addition to the information management system and must be applied, unless otherwise directed by the applicable CSA, regardless of the media of the TOP SECRET information, to include information processed and stored on authorized information systems. * * * * * (6) Reproduction of classified information.

, which permits DoD to disclose information to a litigation support contractor if the disclosure is for the sole purpose of providing administrative, technical, or professional services to DoD in anticipation of or during litigation. The statute also requires that, under a contract, the contractor agree to and acknowledge specific terms and conditions on the use and disclosure of the information, and that any violation of these terms and conditions is a basis for termination of the litigation support contract. DFARS clause 252.204-7014 is included in all solicitations and

contracts that involve litigation support services. The clause contains all of the information in DFARS provision 252.204-7013, as well as a statement that violation of the terms and conditions of the clause is a basis for termination of the contract. As such, the DFARS provision is redundant and can be removed from the DFARS. The repeal of the DFARS provision implements a recommendation from the DoD Regulatory Reform Task Force. On February 24, 2017, the President signed Executive Order (E.O.) 13777, 'Enforcing the Regulatory Reform Agenda,' which established a Federal policy 'to alleviate unnecessary regulatory burdens' on the American people. In accordance with E.O. 13777, DoD established a Regulatory Reform Task Force to review and validate DoD regulations, including the DFARS. A public notice of the establishment of the DFARS Subgroup to the DoD Regulatory Reform Task Force, for the purpose of reviewing DFARS provisions and clauses, was published in the Federal Register at 82 FR 35741 on August 1, 2017, and requested public input. No public comments were received on the provision. Subsequently, the DoD Task Force reviewed the requirements of DFARS provision 252.204-7013 and determined that it could be repealed.

III. Applicability to Contracts at or Below the Simplified Acquisition Threshold and for Commercial Items, Including Commercially Available Off-the-Shelf Items This rule only removes obsolete DFARS provision 252.204-7013, Limitations on the Use or Disclosure of Information by Litigation Support Contractors. This rule does not create any new provisions or clauses or impose any new requirements on contracts at or below the simplified acquisition threshold and for commercial items, including commercially available off-the-shelf items.

IV. Publication of This Final Rule for Public Comment Is Not Required by Statute The statute that applies to the publication of the Federal Acquisition Regulation (FAR) is Office of Federal Procurement Policy statute (codified at title 41 of the United States Code). Specifically, 41 U.S.C. 1707(a)(1)

a physical item such as hardware, firmware, computing platform, network device, or other technology component) or intangible (e.g., humans, data, information, software, capability, function, service, trademark, copyright, patent, intellectual property, image, or reputation). The value of an asset is determined by stakeholders in consideration of loss concerns across the entire system life cycle. Such concerns include but are not limited to business or mission concerns, as defined in NIST SP 800-160 V2R1 (incorporated by reference, see §.170.2). Asset Categories means a grouping of assets that process, store or transmit information of similar designation, or provide security protection to those assets. (CMMC-custom term) Authentication is defined in FIPS PUB 200 Mar2006 (incorporated by reference, see §.170.2). Authorized means an interim status during which a CMMC Ecosystem member (person or organization), having met all criteria for the specific role they perform other than the required ISO/IEC accreditations, may act in that role for a specified time as set forth in §.170.8 for the Accreditation Body and §.170.9 for C3PAOs. (CMMC-custom term) Capability means a combination of mutually reinforcing controls implemented by technical means, physical means, and procedural means. Such controls are typically selected to achieve a common information security or privacy purpose, as defined in NIST SP 800-37 R2 (incorporated by reference, see §.170.2). Cloud Service Provider (CSP) means an external company that provides cloud services based on cloud computing. Cloud computing is a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction. This definition is based on the definition for cloud (printed page 83218) computing in NIST SP 800-145 Sept2011. (CMMC-custom term) CMMC Assessment and Certification Ecosystem means the people and organizations described in subpart C of this part. This term is sometimes shortened to CMMC Ecosystem. (CMMC-custom term) CMMC Assessment Scope means the set of all assets in the OSA's environment that will be assessed against CMMC security requirements. (CMMC-custom term) CMMC Assessor and Instructor Certification Organization (CAICO) is defined in §.170.10 and means the organization responsible for training, testing, authorizing, certifying, and recertifying CMMC certified assessors, certified instructors, and certified professionals. (CMMC-custom term) CMMC Instantiation of eMASS means a CMMC instance of the Enterprise Mission Assurance Support Service (eMASS), a government owned and operated system. (CMMC-custom term) CMMC Security Requirements means the 15 Level 1 requirements listed in the 48 CFR 52.204-21(b)(1)

3.4.3 | Risk ... 3.4.3 Risk The risk to an organization is the intersection of: - · the vulnerabilities and threats to the organization - · the likelihood that the vulnerability and threat event will be realized - · the impact to the organization should the event be realized A meaningful risk assessment must be performed in the context of the cyber-ecosystem and the impact to an organization should a loss or degradation occur.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by Federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, Federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in Federal information systems. - · Current research in Cyber Physical Systems is focused on Supervisory Control and Data Acquisition (SCADA) systems, but Additive Manufacturing is different. - · Researchers were able to intercept a job initialization file and decode it, allowing attackers to potentially alter printer parameters mid-print. The STL (or newer AMF) standard files are especially vulnerable to attacks which alter a design. - · The presenters described an experiment run on students at Virginia Tech. Seven groups of students were given an 'extra credit' assignment to design a standard dog bone, print it, and test it.

Some comments addressed the DoD's internal policies and training efforts to prepare the Government workforce for CMMC program implementation. For example, some commenters opined that the rule's focus on contactor responsibilities misses the true risk that lies further up obscure supply chains. Another commenter recommended DoD work with contractors in each sector to provide clear guidance on the types of data that the Department would consider CTI. One commenter requested DoD acknowledge that human factors influence DIB cybersecurity while another stated DoD should provide uniform web-based training at no cost to ensure applicable training requirements are satisfactorily met. Another asked whether DoD PMs would receive CMMC related training prior to implementation. Another comment asked whether specific risk mitigating approaches, such as product monitoring or software testing might suffice to manage supply chain risk considering lack of visibility into the origins of 3rd and 4th tier components. One commenter perceived the CMMC requirement for Program Managers to identify the level of assessment requirement appropriate for a solicitation as removing the contract award decision from the USD(A&S). One commenter stated more information about procedures for implementing CMMC into government-wide contracts is needed. Another commenter expressed a need to use a basic contract that is unclassified, and any CUI would be contained in a separate appendix to allow sub-contractors to plan with their Prime to access the information on the Prime's network and avoid requirements for their own CMMC certification. Another comment recommended revisions to describe that medium assurance certificates for incident reporting are a DFARS clause 252.204-7012 requirement, independent of CMMC program requirements. Two commenters criticized the DFARS clause 252.204-7020 requirement to allow 'full access' to contractor facilities, systems, and personnel for the purposes of DIBCAC assessment, or for damage assessment following incident, and recommended that the CMMC program not include or rely on this authority. Another commenter recommended that, prior to issuing a final rule on CMMC, DoD work with other relevant agencies to integrate and harmonize the numerous regulatory changes that impact contractors' capacity to safeguard data and systems. One commenter suggested rule publication be delayed until DoD articulates the benefit expected from contractor compliance with the rule. Response: All recommendations to revise other Government-wide or DoD policies and programs are beyond the scope of the CMMC rule.

, at least one court has stated that compliance obligations are limited to the plain words of regulatory text and that a requirement to 'implement' does not mean that a requirement must be in place throughout the regulated entity's enterprise. [639] Additionally, the standards for facility access controls, workstation use, and device and media controls all require a regulated entity to implement policies and procedures, while the standard for workstation security requires regulated entities to implement physical safeguards. The differences in regulatory text among these provisions could be interpreted to mean that a regulated entity's obligations differ depending on whether a provision requires it to implement only policies and procedures or whether the provision requires the implementation of something more. This may confuse regulated entities and lead some to believe that less comprehensive protection is needed for ePHI subject only to policies and

procedures. The Department believes that the current Security Rule provides a clear path for regulated entities to protect the confidentiality, integrity, and availability of ePHI. However, as discussed above, we also believe recent caselaw has created confusion about the steps regulated entities must take to adequately protect the confidentiality, integrity, and availability of ePHI, as required by the statute. Further, the conditions highlighted by caselaw may also cause regulated entities to misinterpret the regulatory text that connects the current maintenance requirement at 45 CFR 164.306(e), the documentation requirement at 45 CFR 164.316, and the requirement to implement physical safeguards. For example, regulated entities may be confused about how 45 CFR 164.316 requires a regulated entity to document the policies and procedures for specific physical safeguard in 45 CFR 164.310 (or across any other safeguard). In this case, the regulated entity also might not apply the implementation specifications to retain, make available, and review documentation of how it has operationalized the physical safeguard. Failing to connect these provisions would lead to inadequate protection of ePHI and/or an inability to demonstrate compliance with the Security Rule. Our experience enforcing the Security Rule provides examples of the types of breaches that can occur because of absent or insufficient physical safeguards: An investigation of a large health system indicated potential failures to implement policies and procedures and facility access controls to limit physical access to the electronic information systems housed within a large data support center. While the health system did have video surveillance, the investigation found indications that laptops were stored in an interior room that was unlocked and the facility did not have an alarm system. [640]

(B) From subsections (c)(4), (d), and (f) because providing access to this information could result in the concealment, destruction or fabrication of evidence and jeopardize the safety and well being of informants, witnesses and their families, and law enforcement personnel and their families. Disclosure of this information could also reveal and render ineffectual investigative techniques, sources, and methods used by this component and could result in the invasion of privacy of individuals only incidentally related to an investigation. Investigatory material is exempt to the extent that the disclosure of such material would reveal the identity of a source who furnished the information to the Government under an express promise that the identity of the source would be held in confidence, or prior to September 27, 1975 under an implied promise that the identity of the source would be held in confidence. This exemption will protect the identities of certain sources that would be otherwise unwilling to provide information to the Government. The exemption of the individual's right of access to his/her records and the reasons therefore necessitate the exemptions of this system of records from the requirements of the other cited provisions. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsection (e)(2) because collecting information to the fullest extent possible directly from the subject individual may or may not be practical in a criminal investigation. (printed page 14773) (E) From subsection (e)(3) because supplying an individual with a form containing a Privacy Act Statement would tend to inhibit cooperation by many individuals involved in a criminal investigation. The effect would be somewhat adverse to established investigative methods and techniques. (F) From subsections (e)(4)(G), (H), and (I) because it will provide protection against notification of investigatory material which might alert a subject to the fact that an investigation of that individual is taking place, and the disclosure of which would weaken the on-going investigation, reveal investigatory techniques, and place confidential informants in jeopardy who furnished information under an express promise that the sources' identity would be held in confidence (or prior to the effective date of the Act, under an implied promise). In addition, this system of records is exempt from the access provisions of subsection (d).

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 2. The Fundamentals 267 This section describes the assumptions and methodology used to develop the enhanced security requirements for nonfederal systems and organizations to protect the confidentiality, integrity, and availability of CUI associated with critical systems or high value assets. 2.1. Enhanced Security Requirement Assumptions The enhanced security requirements in this publication are based on the following assumptions:

- Federal information that is designated as CUI has the same value whether such information resides in a federal or nonfederal system or organization.
- Statutory and regulatory requirements for the protection of CUI are consistent in federal a

assurance requirement Beta-testing is a primary assurance method for commercial vendors. - All of the assurance requirements apply to the TCB and not to the entire product This restriction is too strong. Some requirements, for example configuration management should include the entire product - Operational assurance needs to be decoupled from the functionality requirements and treated separately from functionality and development assurance (much like the ITSEC's effectiveness requirements). - We expected the PC would be able to handle conceptually complex systems. - The PC suggests that the existence of a defined TCB is a mandatory requirement for any product to be evaluated. The ITSEC view is that while a defined TCB is a valid method, it is not the only method for achieving assurance. - The chief concern is that the basis in science on which the TCSEC is based (i.e., the reference monitor concept) is clearly not the basis upon which the PC is founded. Certain aspects of some security policies (e.g., confidentiality and integrity) can be implemented with high-assurance using the reference monitor concept Others cannot (e.g., availability). The PC should embrace the reference monitor concept for high-assurance while recognizing the utility and limitations of low-assurance mechanisms. - The PC lacks a single, consistent assurance paradigm, and in some respects destroys the TCSEC's operational assurance requirements.

) before an interim or final rule takes effect, DoD will submit a copy of the interim or final rule with the form, Submission of Federal Rules under the Congressional Review Act, to the U.S. Senate, the U.S. House of Representatives, and the Comptroller General of the United States. A major rule under the Congressional Review Act cannot take effect until 60 days after it is published in the Federal Register . The Office of Information and Regulatory Affairs has determined that this rule is not a major rule as defined by 5 U.S.C. 804 . VI. Regulatory Flexibility Act A final regulatory flexibility analysis (FRFA) has been prepared consistent with the Regulatory Flexibility Act, 5 U.S.C. 601 , et seq. The FRFA is summarized as follows: This final rule is necessary to revise the Defense Federal Acquisition Regulation Supplement (DFARS) to incorporate the expanded capabilities of the Supplier Performance Risk System (SPRS), made possible by recent technical enhancements. SPRS is a DoD enterprise application that retrieves price, item, quality, delivery, and contractor performance data from Government reporting systems. SPRS collects quality and delivery data from Government systems to develop risk assessments. The system provides three risk assessments for contracting officer use in evaluations of quotations and offers: an item risk assessment, a price risk assessment, and a supplier risk assessment. The objective of the final rule is to notify offerors, via the new solicitation provision at DFARS 252.204-7024, that SPRS collects performance data from a variety of Government sources on awarded contracts to develop item risk, price risk, and supplier risk assessments for contracting officers to consider during evaluation of quotations or offers. The final rule also requires contracting officers to consider the supplier risk assessment in the determination of contractor responsibility. No comments were received in response to the initial regulatory flexibility analysis. The Federal Procurement Data System indicates that in fiscal years 2020 through 2022, DoD awarded an average of 483,364 contracts per year for both products and services, of which an average of 338,039 (approximately 70 percent) were awarded to an average of 22,760 unique small businesses. This rule does not require any specific reporting, recordkeeping, or compliance requirements. No significant economic impact on small businesses is anticipated as a result of the final rule. DoD does not expect small entities will be materially affected by this rule. There are no (printed page 17338) known significant alternatives to the rule. VII. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). List of Subjects in 48 CFR Parts 204 , 208 , 209 , 212 , 213 , 215 , 216 , and 252 Government procurement Jennifer D. Johnson, Editor/Publisher, Defense Acquisition Regulations System.

<https://www.dni.gov/files/NCSC/documents/Regulations/SEAD-3-Reporting-U.pdf>), to executive branch agencies or covered individuals with an effective date of June 12, 2017. SEAD 3 defines covered individuals as: A person who performs work for or on behalf of the executive branch who has been granted access to classified information or holds a sensitive position, but does not include the President or the Vice President. a person who performs work for or on behalf of a state, local, tribal, or private sector entity, as defined in E.O. 13549 , who has been granted access to classified information or holds a sensitive position, but does not include duly elected or appointed governors of a state or territory, or an official who has succeeded to that office under applicable law; and a person working in or for the legislative or judicial branches who has been granted access to classified information or holds a sensitive position and the investigation or determination was conducted by the executive branch, but does not include members of Congress,

Justices of the Supreme Court, or Federal judges appointed by the President. covered individuals are not limited to government employees and include all persons, not excluded under paragraphs D.5(a), (b), or (c) of SEAD 3, who have access to classified information or who hold sensitive positions, including, but not limited to, contractors, subcontractors, licensees, certificate holders, grantees, experts, (printed page 83303) consultants, and government employees. SEAD 3 identifies required reporting of data elements that are contained in the Standard Form-86, ·Questionnaire for National Security Positions· (available at https://www.opm.gov/forms/pdf_fill/sf86.pdf), which applicants and clearance holders complete during the initial and periodic reinvestigation processes, respectively. SEAD 3 requires these elements to be reported prior to participation in such activities or otherwise as soon as possible following the start of their involvement. Most notably, SEAD 3 requires covered individuals to obtain prior agency approval before conducting unofficial foreign travel. For this rule, SEAD 3 applies only for those contractor personnel who have been granted eligibility for access to classified information through the NISP. In accordance with paragraph E.4 of SEAD 3, NISP CSAs, acting on behalf of Heads of agencies or designees, for the NISP contractors under their security cognizance may determine that operational and mission needs preclude strict adherence to these reporting requirements. In those instances, a NISP CSA may provide CSA guidance to supplement unique CSA mission requirements to the contractors under its security cognizance of equivalent notification, briefing and reporting to be accomplished. III. Requirements From Section 842 of Public Law 115-232 Currently, the NISPOM and 32 CFR part 2004

3.1.6 | Review Preparation or Execution ... 3.1.6 Review Preparation or Execution Similar to Section 3.

- Training on specific tools required for employees to perform security-related job duties - Training for employees who have privileged access to applications or systems - Training for oversight roles such as information systems security officer (ISSO), information systems security manager (ISSM), or auditors - Training for employees who manage access and authorizations to applications and systems - Training on organizational policies and procedures related to security and privacy configurations, settings, controls, etc. - Cybersecurity for employees in leadership positions, such as 'Cybersecurity for Executives,' Cybersecurity for System Owners,' or 'Becoming A Chief Information System Officer'

- (1) The definition is quoted (i.e., not adapted) from a federal law or regulation. - (2) The definition is quoted from an international, federal, or widely adopted technical standard [e.g., International Organization for Standardization (ISO), FIPS, American National Standards Institute (ANSI)], a common English or mathematical dictionary, or is an authoritative original technical source (e.g., the Defense Discovery Metadata Specification for the definition of the Defense Discovery Metadata Standard). - (3) The definition is quoted from an Office of Management and Budget (OMB) Policy or Circular, CNSS Policies and Directives, or similar documents. - (4) The definition is from NIST SPs, CNSS Instructions, OMB Memorandum, similar documents, or a specialized dictionary. - (5) The definition is from Government Accountability Office (GAO) Reports, CNSS Advisory Memoranda, Agency-specific standards, regulations, and policies. - (6) The definition is from NIST IRs, white papers, academic or technical papers, or other publications. - (7) The definition is from draft, archived, or superseded publications.

Through interactions with the group and analysis of existing systems, the contracted security consultant is drafting a security profile specification document that defines the security environment, threats, vulnerabilities, and assumptions about a typical systems in the terminology used within the industrial control community. Along with this specification development, the intermediate task of performing vulnerability and threat analysis within the specific sector industries of the PC'SRF is being conducted through working groups. Once the security profile specification is drafted, work will begin to translate it into a common set of formal information security requirements (Common Criteria, ISO/IEC 15408, Protection Profiles) and documented best practices for the systems described. Organization based members of the PCSRF are also discussing the future requirements of training and certification to insure the implementation of IT security in process control systems.

memory may pass information from one user to another user. In other words, when objects are reused no residual information should exist on that object. This protects the confidentiality of the information. This is typically a feature provided by operating system and software vendors. Example You are a system administrator responsible for creating and deploying the system hardening procedures for your company's computers. You ensure that the computer baselines include software patches to prevent attackers from exploiting flaws in the processor architecture to read data (e.g., the Meltdown and Spectre exploits). You also verify that the computer operating system is configured to prevent users from accessing other users' folders [a]. Potential Assessment Considerations · Are shared system resources identified and documented [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.13.4

Additionally, the Department is concerned about the extent to which regulated entities have updated their security measures to adjust to the changes in the health care environment and their operations, including new and emerging threats to the confidentiality, integrity, and availability of ePHI. And the Department is not alone in its concerns. NCVHS serves as the Department's advisory body for HIPAA. [122] Given the increase in cybersecurity incidents affecting the health care sector, NCVHS held a series of public hearings on cybersecurity to better understand how to protect ePHI and individuals. In response to those hearings, NCVHS submitted several recommendations to the Department regarding the importance of strengthening the Security Rule. [123] As discussed above, HIPAA requires the Secretary to rely on NCVHS' recommendations [124] with respect to standards promulgated under the statute. Given the importance of strong security measures, the changed environment and operations for health care, uncertainty expressed by regulated entities regarding their compliance obligations, deficiencies identified by OCR in its investigations of regulated entities, and the recommendations of NCVHS, we believe that it is necessary and appropriate for the Department to propose modifications to clarify and strengthen the Security Rule.

A. Strong Security Standards Are Essential to Protecting the Confidentiality, Integrity, and Availability of ePHI and Ensuring Quality and Efficiency in the Health Care System A primary purpose of HIPAA's Administrative Simplification provisions [125] is to, among other things, ·improve [. . .] the efficiency and effectiveness of the health care system, by encouraging the development of a health information system through the establishment of uniform standards and requirements for the electronic transmission of certain health information.· [126] As Congress recognized when it enacted HIPAA, protecting the security of ePHI is essential for accomplishing this goal. Members of Congress acknowledged at that time that the provisions of HIPAA would create electronic databases of PHI, enabling the PHI to be transmitted electronically with both the benefits and risks that accompany such electronic transactions. [127] Congressional statements leading up to HIPAA's enactment demonstrate Congress' recognition of the potential risks of the shift from paper recordkeeping to electronic: ·We need to be very careful about how safe and secure that information is from prying eyes. Some of it may be extremely sensitive and could be used in a malicious or discriminatory manner.· [128] Accordingly, HIPAA required the establishment of strict security standards for health information.

s e-mail servers are another likely source of information. Each of the server IP addresses listed in the e-mail header should contain some record of the e-mail, including the message ID value, which should facilitate quick identification of pertinent records. As mentioned previously, the final e-mail server in the list may contain a copy of the e-mail. Backups of that server may contain a copy of the e-mail, but only if it was held there for delivery for several hours or more. Other services associated with e-mail, such as antivirus software and spam filters, may also contain basic records of e-mail activity, but are unlikely to contain many details. Another possible source of information is authentication records. Although few e-mail servers require users to authenticate to send e-mail, they typically do require authentication to deliver e-mail to users. Because users often send and receive e-mail during a single session, authentication logs may contain records for receiving e-mail that can be helpful in determining who may have sent a particular e-mail. Another possible source of information is a record of the network traffic generated by sending or receiving the e-mail. Packet sniffers or network forensic analysis tools that were monitoring network activity might have captured the activity, including the actual IP addresses of the sending or receiving hosts, the contents and header of the e-mail, and any associated authentication activity. Ultimately, the incident handler should identify the hosts that were used to send and receive the e-mail, as well as all intermediate hosts that transferred the e-mail from sender to receiver.

(Mar. 23, 2010) (codified at 42 U.S.C. 1320d note). Back to Citation 127. · See statement of Sen. Simon, *supra* note 34; see also 155 Cong. Rec. H1562 (statement of Rep. Markey) (stating that ARRA includes provisions for health IT with built-in privacy and security); Implementation of the Health Information Technology for Economic and Clinical Health (HITECH) Act: Hearing Before the House Committee on Energy and Commerce Subcommittee on Health, 111th Cong. 11-12 (2010) (statement of Rep. Schakowsky) (explaining that the HITECH Act strengthened Federal privacy and security laws to protect personal identifying information from misuse to ensure that individuals would be willing to use electronic records). Back to Citation 128. · Statement of Sen. Simon, *supra* note 34. Back to Citation 129. · See section 1173(d)(2) of HIPAA (codified at 42 U.S.C. 1320d-2(d)(2)) and section 13401 of ARRA (codified at 42 U.S.C. 17931(a)) and 45 CFR 164.306 . Back to Citation 130. · See Hadi Ghayoomi, et al., ‘Assessing resilience of hospitals to cyberattack,’ *Digital Health*, p. 2 (2021), <https://doi.org/10.1177/20552076211059366> ; ‘Beyond Security Patches-Fundamental Incentive Problems in Health Care Cybersecurity,’ *supra* note 116; Jessica Brewer, et al., ‘An Insight into the Current Security Posture of Healthcare IT: A National Security Concern,’ *The Institute for Critical Infrastructure Technology*, p. 3 (2019), <https://www.icitech.org/post/an-insight-into-the-current-security-posture-of-healthcare-it-a-national-security-concern> . Back to Citation 131. · ‘Cost of a Data Breach Report 2023,’ IBM, p. 13 (2023) (explaining that the average cost of a health care data breach was \$7.13 million in 2020), <https://www.ibm.com/reports/data-breach> . Back to Citation 132. · ‘Report on Improving Cybersecurity In The Health Care Industry,’ *supra* note 117, p. 14-15. Back to Citation 133. Id. Back to Citation 134. · ‘An Insight into the Current Security Posture of Healthcare IT: A National Security Concern,’ *supra* note 130, p. 3. Back to Citation 135. See, e.g., Caleb J. Kumar, ‘New Dangers in the New World: Cyber Attacks in the Healthcare Industry,’ *Intersect*, Volume 10, No. 3, p. 3 (2017). Back to Citation 136. · ‘An Insight into the Current Security Posture of Healthcare IT: A National Security Concern,’ *supra* note 130, p. 3. Back to Citation 137. · ‘Report on Improving Cybersecurity In The Health Care Industry,’ *supra* note 117, p. 2. Back to Citation 138. Id. at 18. Back to Citation 139. · ‘CISA INSIGHTS: Provide Medical Care Is In Critical Condition: Analysis and Stakeholder Decision Support to Minimize Further Harm,’ Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security, p. 12-15 (Sept. 2021), https://www.cisa.gov/sites/default/files/publications/CISA_Insight_Provide_Medical_Care_Sep2021.pdf . Back to Citation 140. Id. Back to Citation

Malicious cyber actors have targeted and continue to target the DIB sector that consists of approximately 220,000 small-to-large sized entities that support the warfighter. In particular, actors ranging from cyber criminals to nation-states continue to attack companies and organizations that comprise the Department's multi-tier supply chain including smaller entities at the lower tiers. From at least January 2020, through February 2022, the Federal Bureau of Investigation (FBI), National Security Agency (NSA), and Cybersecurity and Infrastructure Security Agency (CISA) observed regular targeting of U.S. cleared defense contractors (CDCs) by Russian state-sponsored cyber actors. The actors have targeted sensitive, unclassified information, as well as proprietary and export-controlled technology. The acquired information provides significant insight into U.S. weapons platforms development and deployment timelines, vehicle specifications, and plans for communications infrastructure and IT. By acquiring proprietary internal documents and email communications, adversaries may be able to adjust their own military plans and priorities, hasten technological development efforts, inform foreign policymakers of U.S. intentions, and target potential sources for recruitment. [50] In addition to stealing intellectual property for military gains, Russia may conduct cyber-attacks against the U.S. for retaliatory purposes. On March 21, 2022, that the Biden-Harris Administration stated intelligence indicates that the Russian Government and Russian-aligned cybercrime groups have threatened to conduct cyber operations in retaliation for perceived cyber offensives against the Russian Government or the Russian people. [51] The aggregate loss of intellectual property and CUI from the DoD supply chain severely undercuts U.S. technical advantage, limits, and disrupts business opportunities associated with technological superiority, and ultimately threatens our national defenses and economy. By incorporating heightened cybersecurity into acquisition programs, the CMMC Program provides the Department assurance that contractors and subcontractors are meeting DoD's cybersecurity requirements and provides a key mechanism to adapt to an evolving threat landscape. This is critically important to the Department because defense contractors are the target of increasingly frequent and complex cyberattacks by adversaries and non-state actors. Dynamically enhancing DIB cybersecurity to meet these evolving threats and safeguarding the information that supports and enables our warfighters is a top priority for the Department. The CMMC Program is a key component of

the Department's DIB cybersecurity effort.

Katerina Megas, the program manager for the NIST Cybersecurity for the IoT Program, gave a brief introductory presentation. She thanked participants for attending, provided a summary of the agenda, and presented information on the NIST Cybersecurity for IoT Program. Ms. Megas reviewed the goals of the program and five principles that guide its execution. She emphasized the importance of risk management in NIST's approach to IoT cybersecurity guidance, describing the view of the risk management hierarchy from enterprise down to systems, and then extending on to IoT devices that are components of federal information systems. Ms. Megas also pointed out that NIST guidance needn't have 'IoT' in the title to be applicable to IoT cybersecurity, noting that the NIST security controls contained in SP 800-53, and other guidance documents that address zero-trust architecture and supply chain security, among other topics, are also relevant and useful. She concluded by reminding participants that the workshop discussions were focused on cybersecurity for federal information systems, which guided the selection of topics in the agenda. Takeaway 3: Supply chain security and transparency are important but very complex. A number of challenges were identified regarding developing transparency and trust in IoT device supply chains. Participants noted the role of cloud systems in IoT devices as part of the supply chain, and that the constantly evolving nature of cloud implementations and business models could leave customers with no insight into any changes in the cloud that could alter what was an acceptable level of security at time of purchase. The provision of a software bill of materials (SBOM) ⁶ can help with visibility into an IoT device's implementation, but there are challenges both with the complexity of creating complete, accurate SBOMs and with trust that either the SBOM or the device has not been altered so that they no longer match.

AC.L2-3.1.11 · Session Termination CMMC Assessment Guide · Level 2 | Version 2.13 39 FURTHER DISCUSSION Configure the system to terminate user sessions based on the organization's policy. Session termination policies can be simple or sophisticated. Examples are inactivity (end the session after a specified duration (e.g., one hour ³³) of inactivity), day/time (all sessions are terminated at the end of the established workday), misbehavior (end the session due to an attempted policy violation), and maintenance (terminate sessions to prevent issues with an upgrade or service outage). If there is no automatic control of user sessions, an attacker can take advantage of an unattended session. Example 1 You manage systems containing CUI for your organization and configure the system to terminate all user sessions after 1 hour of inactivity [a]. As the session timeout approaches, the system prompts users with a warning banner asking if they want to continue the session. When the session timeout does occur, the login page pops up, and the users must log in to start a new session [b]. Example 2 A user is logged into a corporate database containing CUI but is not authorized to view CUI. The user has submitted a series of queries that unintentionally violate policy, as they attempt to extract CUI that the user is not authorized to view [a]. The session terminates with a warning as a result of a violation of corporate policy [b]. The user must reestablish the session before being able to submit additional legitimate queries. Potential Assessment Considerations · Are the conditions in which a user session must be terminated described (e.g., after a period of inactivity or after a defined time limit) [a]? · Are procedures documented that describe how to configure the system to enable automatic termination of user sessions after any of the defined conditions occur [b]? · Are user sessions terminated based on organization-defined conditions [a,b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.1.11 33 Review DoD Cybersecurity FAQ Q53.2 for information on minimum values.

3.1.2 Supports Guidance for Control Selection... 3.1.2 Supports Guidance for Control Selection Informed and judicious decision making in security control selection requires an understanding of how security controls work together to achieve broader security protections.

3.2.5 Determine Updated Risk Assessment... 3.2.5 Determine Updated Risk Assessment With an understanding of the threat sources and vulnerabilities introduced by the IoT device, as well as the resulting likelihood of occurrence and magnitude of impact, organizations can perform an updated risk assessment of the information system using information available about the proposed IoT device.

The role of System Engineering and associated processes within the DoD acquisition process is beyond the scope of this rule. ITRA assessments provide a view of program technical risk and are not well-suited to the assessment of contractor owned information systems against standards for safeguarding CUI. CMMC Program requirements do not clash with Program Office responsibilities, but instead

provide Program Manager's with a mechanism for validating that contractors are compliant with the rules for protecting DoD CUI. b. FedRAMP Program and FedRAMP Equivalency Comment: Many commenters took issue with the requirements for FedRAMP Moderate Equivalency, as referenced in DFARS clause 252.204-7012 and defined in a separate DoD policy memo. Some merely highlighted discrepancies or highlighted concerns about their ability to meet the FedRAMP Moderate Equivalency requirements. Others recommended revisions to that policy, or to the DFARS clause 252.204-7012 clause, or both. Some recommended the FedRAMP Moderate Equivalency policy memo be incorporated into the DFARS clause 252.204-7012 clause. Other suggestions ranged from eliminating equivalency to meet requirements, allowing 3PAO attestation to equivalency, requiring all FedRAMP Moderate Equivalency candidates to be assessed by the same C3PAO or allowing equivalency to be established through other industry certifications or third-party security assessments, i.e., SOC, ISO/IEC 27001. One commenter requested that applications hosted on a FedRAMP Moderate environment only need to meet the CMMC level of the data the application will process. Another suggested that all Cloud Service Providers be required to meet the same CMMC requirement as the OSCs they support. One commenter recommended expanding the scope of CMMC Program to include assessing other security requirements in DFARS clause 252.204-7012, to include the use of FedRAMP Moderate cloud environment. Comments also expressed that it is unreasonable to expect any cloud provider to share security documentation with a customer or C3PAO since they limit dissemination of this information due to operational security needs. Another commenter noted that the proposed rule does not cover all types of information that contractors may handle, such as classified information, export-controlled information, or proprietary information and they recommended the DoD clarify applicability of the CMMC program for these types of information. Response:

) requires agencies to assess anticipated costs and benefits before issuing any rule whose mandates require spending in any one year of \$100 million in 1995 dollars, updated annually for inflation. This rule will not mandate any requirements for State, local, or tribal governments, nor will it affect private sector costs. E. Public Law 96-511, 'Paperwork Reduction Act' (44 U.S.C. Chapter 35) It has been determined that this amendment rule does not impose additional reporting or recordkeeping requirements under the Paperwork Reduction Act of 1995. There is an (printed page 55283) existing information collection for 32 CFR part 159 that has been reviewed and approved by the OMB under OMB Control Number 0704-0549, 'Defense Federal Acquisition Regulation Supplement, part 225, Foreign Acquisition, and Defense Contractors Performing Private Security Functions Outside the United States.' The amendments to this rule neither increase nor decrease the public burden nor cost to the Federal Government associated with this collection. F. Executive Order 13132 , 'Federalism' Executive Order 13132 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct requirement costs on State and local governments, preempts State law, or otherwise has federalism implications. This rule will not have a substantial effect on State and local governments. G. Executive Order 13175 , 'Consultation and Coordination With Indian Tribal Governments' Executive Order 13175 establishes certain requirements that an agency must meet when it promulgates a proposed rule (and subsequent final rule) that imposes substantial direct compliance costs on one or more Indian tribes, preempts tribal law, or effects the distribution of power and responsibilities between the Federal Government and Indian tribes. This rule will not have a substantial effect on Indian tribal governments. List of Subjects in 32 CFR Part 159 Government contracts Reporting and recordkeeping requirements Security measures Accordingly, 32 CFR part 159 is amended as follows: PART 159-PRIVATE SECURITY CONTRACTORS (PSCs) OPERATING IN CONTINGENCY OPERATIONS, HUMANITARIAN OR PEACE OPERATIONS, OR OTHER MILITARY OPERATIONS OR EXERCISES 1. The authority citation for part 159 is revised to read as follows: Authority: Sec. 862, Pub. L. 110-181 , 122 Stat. 253; Sec. 832, Sec 853, Pub. L. 110-417 , 122 Stat. 4535; Sec. 831-833, Pub L. 111-383 , 124 Stat. 4276. 2. Revise the heading for part 159 to read as set forth above. 3. Amend §-159.2 by: a. In paragraph (a)(1): i. Adding '(CJCS)' after 'Office of the Chairman of the Joint Chiefs of Staff'. ii. Adding '(DoD)' after 'the Office of the Inspector General of the Department of Defense'. iii. Removing 'organizational entities in the Department of Defense' and adding in its place 'organizational entities in the DoD'. b. Revising paragraph (a)(2). c. Adding paragraph (a)(3). d. Revising paragraph (b)(1). e.

for those FOIA requests for data not deemed clearly exempt from disclosure under Exemption 4. The submitter notice letter should include, as an attachment, a copy of the requested information. Any objections to release provided by the submitter shall be evaluated. The final decision to disclose information claimed to be exempt under Exemption 4 shall be made by an official equivalent in rank

to the official who would make the decision to withhold that information under the FOIA. When a substantial issue has been raised or when the objections submitted lack specificity, the DoD Component may seek additional information from the submitter and afford the submitter a reasonable opportunity to present arguments on the legal and substantive issues involved prior to making an agency determination. If the Component and submitter cannot come to agreement as to what information is exempt from release under Exemption 4, the Component shall provide the submitter a date on which the information in question will be released to the FOIA requester. This date should provide the submitter sufficient time to block the release of the information by obtaining an injunction in Federal Court (which is known as a reverse FOIA lawsuit), if the submitter so chooses. If no response is forthcoming the component shall release the information on the date provided to the submitted. (ii) The requester shall be notified when: (A) The Component notifies the submitter of the FOIA request and asks for comments. (B) The Component advises the submitter that the requested information will be released over the submitter's objections. (iii) The submitter shall be notified immediately whenever the requester (printed page 71859) brings suit seeking to compel disclosure of the submitter's information. (iv) If the submitted information is a proposal provided in response to a solicitation for a competitive proposal, and the proposal is in DoD possession and control and meets the requirements of 10 U.S.C. 2305(g) , the proposal shall not be disclosed, and no submitter notification and subsequent analysis is required. The proposal shall be withheld from public disclosure pursuant to Reference (m) and Exemption 3. This statute does not apply to bids, unsolicited proposals, or any proposal that is set forth or incorporated by reference in a contract between the DoD Component and the offeror that submitted the proposal. In such situations, normal submitter notice and analysis shall be conducted in accordance with § 286.18 (l) except sealed bids that are opened and read to the public. The term "proposal" means information contained in or originating from any proposal, including a technical, management, or cost proposal submitted by an offeror in response to solicitation for a competitive proposal. The term "proposal" does not include an offeror's name, total price, or unit prices when set forth in a record other than the proposal itself.

(2) A U.S. subsidiary of a foreign entity may be sponsored for a limited entity eligibility determination by a foreign government when the foreign government desires to award a contract or agreement to the U.S. subsidiary that involves access to only that classified information for which the foreign government is the OCA. (3) Limited entity eligibility determinations are specific to the classified information for the requesting GCA or foreign government and the single narrowly defined contract, agreement, or circumstance the request was based on. The limited entity eligibility determination will only be verified to that GCA or foreign government for the authorized level of access to classified information and any limitations to that access to classified information. (4) A limited entity eligibility determination is not an option for contractors that require access to proscribed information when a foreign government has ownership or control over the entity. (5) Release of classified information must be in conformity with the U.S. National Disclosure Policy-1 (provided to designated disclosure authorities on a need-to-know basis from the Office of the Under Secretary of Defense for Policy, Defense Technology Security Administration). (6) A limited entity eligibility determination will be administratively terminated when there is no longer a need for the contractor to access the classified information for which it was sponsored. Administrative termination of one limited entity eligibility determination does not impact a contractor's other limited entity eligibility determinations. (7) If there is no industrial security agreement with the foreign government of the country from which the FOCI is derived, in extraordinary circumstances, a limited entity eligibility determination may also be granted if there is a compelling need to do so consistent with U.S. national security interests and the GCA has informed the applicable CSA that access to classified information by the contractor is essential to contract or agreement performance. Under this circumstance, the entity must follow all provisions of this rule. (f) Qualifications of trustees, proxy holders, and outside directors. Individuals who serve as trustees, proxy holders, or outside directors must meet the following criteria: (1) Trustees and proxy holders must be resident U.S. citizens who can exercise governance and management prerogatives relating to their position in a way that ensures that the foreign owner can be effectively insulated from the entity. (2) Outside directors must be resident U.S. citizens who can exercise governance and management prerogatives relating to their position in a way that ensures that the foreign owner can be effectively separated from the entity's classified work. (3) New trustees, proxy holders, and outside directors must be completely disinterested individuals with no prior involvement with the entity, the entities with which it is affiliated, or the foreign owner.

(Comment 102) Several comments object to the requirement to name a responsible individual as duplicative of a requirement in the registration interim final rule. The majority of these comments ask that FDA use the emergency contact information required in the registration interim final rule in place of the responsible individual. The comments suggest that using the emergency contact information would give the agency rapid access to the information and provide the industry with flexibility. The comments state that there is no demonstrated need for the record of each commercial transaction involving the distribution of food to contain the name of a responsible individual, and that the requirement for a responsible individual is too rigid, as there is a high turnover of employees in many companies and the naming of a specific person as the responsible individual would require frequent updating. (Response) FDA agrees with the comments that there is little utility from requiring that the record of each commercial transaction involving the distribution of food contain the name of a responsible individual, due to the fact that individuals change jobs within and among companies very often, making it unlikely that the person named in the record will have responsibility for the food at issue when FDA seeks to effect a traceback. FDA further notes that, for those facilities required to register under part 1, subpart H, FDA already has the emergency contact designated in the registration under §§ 1.232(d) and (e) and 1.233(d) or § 1.233(e). As explained previously, FDA does not believe this information is necessary for those facilities not required to register under 21 CFR part 1, subpart H, because including an emergency contact telephone number in records being kept will not assist the Secretary in locating the records because FDA would not have the emergency number until it had already accessed the records. (Comment 103) Some comments suggest that, rather than requiring a specific individual, the agency require a department such as a quality assurance department. (Response) As explained in response to comment 63 of this document, FDA has deleted the proposed requirement that a responsible individual be listed in each record. 4. Adequate Description of Type of Food (Comment 104) One comment notes that ·specific variety· is not appropriate (printed page 71599) for many food ingredients and should be changed to ·common name·.

to accept alternate forms of security for PBPs instead of taking title. According to these respondents, such alternate forms of security are common in the commercial marketplace, and allowing contractors without Government-unique accounting systems to provide an alternate form of security is the only way to implement the mandate from Congress to open PBP access to all contractors with GAAP-compliant systems. Response: While title to the property described in paragraph (f) of the clause at FAR 52.232-32, Performance-Based Payments, is the preferred security for receipt of progress payments, the final rule (DFARS 252.232-7012 and 252.232-7013) addresses the concerns and comments expressed concerning title by allowing the use of other forms of security if the contractor's accounting system is not capable of identifying and tracking through the build cycle the property that is allocable and properly chargeable to the contract. 6. Definition of ·Nontraditional Defense Contractor· Comment: Two respondents stated that the DFARS does not define ·nontraditional defense contractor· and recommended inclusion in the DFARS of the definition at 10 U.S.C. 2302(9) . Response: The definition of ·nontraditional defense contractor· at 10 U.S.C. 2302(9) is incorporated in the DFARS at 212.001. However, since the term is now used in part 232, this final rule moves the definition from DFARS 212.001 to DFARS 202.101, so that the definition is applicable throughout the DFARS. 7. Ceiling of 90 Percent Comment: One respondent recommended revision to the proposed rule to provide clarity on the financial ceiling of 90 percent provided for in the FAR. According to the respondent, the DFARS should clearly state that performance-based payments will be based on a percentage of price, and that the ceiling for the basis will be 90 percent (FAR 32.1004(b)(2)(ii)). Response: The DFARS does not restate the 90 percent ceiling that is already stated in FAR 32.1004(b)(2)(ii) and doing so is unnecessary because the DFARS supplements the FAR. Further, performance-based payments are not based on a percentage of price. The bases for performance-based payments are clearly defined in FAR 32.1002. 8. Selection and Valuation of Milestone Events Comment: One respondent recommended that the final rule should clarify in the DFARS that a PBP payment associated with a particular milestone should reflect the value of all work accomplished by the contractor at the time it meets the milestone. This is consistent with current guidance in the PBP Guide, but the respondent has still encountered widespread confusion. According to the respondent, clarifying this interpretation can reduce the administrative burden by allowing flexibility to choose fewer and more meaningful milestones. Response:

DFARS 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, authorizes DoD to release information that is obtained from the contractor (or derived from information obtained from the contractor) under this clause that is not created by or for DoD. It

further states that: (1) The Government will protect against the unauthorized use or release of information obtained from the contractor (or derived from information obtained from the contractor) under this clause that includes contractor attributional/proprietary information; and (2) in making an authorized release of such information, the Government will implement appropriate procedures to minimize the contractor attributional/proprietary information that is included in such authorized release, seeking to include only that information that is necessary for the authorized purpose(s) for which the information is being released. A foundational element of the mandatory reporting requirement is the recognition that the information being shared between the parties may include extremely sensitive information that requires protection. Information regarding the Government's safeguarding of information received from the contractors that require protection can be referenced in the DoD Privacy Impact Assessment (PIA). The PIA provides detailed procedures for handling personally identifiable information (PII), attributional information about the strengths or vulnerabilities of specific covered contractor information systems, information providing a perceived or real competitive advantage on future procurement action, and contractor information marked as proprietary or commercial or financial information (see OMB Control Number 0704-0489, DoD's Defense Industrial Base (DIB) Cybersecurity (CS) Activities Cyber Incident Reporting). Additionally, 32 CFR part 236 implements mandatory information sharing requirements of 10 U.S.C. 391 and 393 by requiring DoD contractors to report key information regarding cyber incidents, and to provide access to equipment or information enabling DoD to conduct forensic analysis to determine if or how DoD information was impacted in a cyber incident. The rule's implementation of these requirements is tailored to minimize the sharing of unnecessary information (whether sensitive or not), including by carefully tailoring the information required in the initial incident reports (32 CFR 236.4(c))

CMMC-Custom Terms CMMC Assessment Guide · Level 2 | Version 2.13 6 · Monitoring: The act of continually checking, supervising, critically observing, or determining the status in order to identify change from the performance level required or expected at an organization-defined frequency and rate.⁶ · Operational plan of action : As used in security requirement CA.L2 -3.12.2, means the formal artifact which identifies temporary vulnerabilities and temporary deficiencies in implementation of requirements and documents how and when they will be mitigated, corrected, or eliminated. The OSA defines the format (e.g., document, spreadsheet, database) and specific content of its operational plan of action. An operational plan of action is not the same as a POA&M associated with an assessment. · Organization-defined: As determined by the OSA being assessed except as defined in the case of Organization-Defined Parameter (ODP). This can be applied to a frequency or rate at which something occurs within a given time period, or it could be associated with describing the configuration of an OSA's solution. · Periodically: Occurring at a regular interval as determined by the OSA that may not exceed one year . As used in many requirements within CMMC, the interval length is organization-defined to provide OSA flexibility, with an interval length of no more than one year. · Security Protection Data (SPD): As defined in 32 CFR § 170.4 means data stored or processed by Security Protection Assets (SPA) that are used to protect an OSC's assessed environment. SPD is security relevant information and includes, but is not limited to: configuration data required to operate an SPA, log files generated by or ingested by an SPA, data related to the configuration or vulnerability status of in-scope assets, and passwords that grant access to the in-scope environment. · System Security Plan (SSP): As defined in 32 CFR § 170.4 means the formal document that provides an overview of the security requirements for an information system or an information security program and describes the security controls in place or planned for meeting those requirements. The system security plan describes the system components that are included within the system, the environment in which the system operates, how the security requirements are implemented, and the relationships with or connections to other systems, as defined in NIST SP 800-53 Rev 5. · Temporary deficiency: As defined in 32 CFR § 170.4 means a condition where remediation of a discovered deficiency is feasible and a known fix is available or is in process. The deficiency must be documented in an operational plan of action. A temporary deficiency is not based on an in-progress initial implementation of a CMMC security requirement but arises after implementation. A temporary deficiency may apply during the initial implementation of a security requirement if, during roll-out, specific issues with a very limited subset of equipment is discovered that must be separately addressed. There is no standard duration for which a temporary deficiency may be active. For example, FIPS-validated cryptography that requires a patch and the patched version is no longer the validated version may be a temporary deficiency.

6 NIST SP 800-160 Vol. 1 R1, Engineering Trustworthy Secure Systems, 2022, Appendix B., p. 55

Given the evolving cybersecurity threat, DoD's best interests are served by ensuring that POA&Ms remain open for no longer than 180 days, regardless of which controls are included or the plan for remediation. The 180-day period starts when the CMMC assessment results are finalized and submitted to SPRS or eMASS, as appropriate. As addressed in §§ 170.17(a)(1)(ii)(B) and 170.18(a)(1)(ii)(B), if the POA&M is not closed out within the 180-day timeframe, the Conditional Certification will expire. If the Conditional Certification expires within the period of performance of a contract, standard contractual remedies will apply, and the OSC will be ineligible for additional awards with CMMC Level 2 or 3 requirements for the information systems within the same CMMC Assessment Scope. The scoring methodology created by the DoD reflects the relative risk to DoD information when a security requirement is NOT MET. As defined in § 170.17(c)(2), a security requirement that is NOT MET may be re-evaluated during the Level 2 certification assessment and for 10 business days following the active assessment period under certain conditions. Likewise, when an OSC executes a contract with a C3PAO it may account for the timeliness of any re-assessments. The language in DFARS clause 252.204-7012 describing the DoD CIO's authority to approve variances is beyond the scope of this rule. A POA&M for CMMC Level 2 can include up to 22 security requirements that have a value of 1, excluding those in § 170.21(a)(2)(iii), or may include non-FIPS-validated encryption and up to 19 security requirements that have a value of 1. The OSA is responsible for maintaining the POA&M that resulted from a CMMC assessment; however, those security requirements that were NOT MET and placed on a POA&M are recorded in eMASS. The OSA is responsible for validating the close-out of the security requirements on the POA&M within 180 days of a self-assessment. The C3PAO or DCMA (as applicable) must perform the POA&M Close-out Assessment for a Final certification assessment. An affirmation of compliance is required upon the completion of any assessment-Conditional, Close-out, or Final-and annually after the completion of a Final assessment. The requirement outlined in § 170.21 for POA&M close out does not apply to Service Level Agreement (SLA) severity levels. The Department declines to include recommended POA&M examples in the rule, as they are already available in existing NIST guidance, or make other word changes to § 170.21. This section of the CMMC rule has been updated to add clarity when discussing the POA&M regarding security requirements that were assessed as NOT MET during a CMMC assessment. These POA&Ms are distinct from an operational plan of action.

g. Assessment Activities and Reporting

1. Data Entry Comment:

spp. detection, a previously unclassified preamendments device, into class II (special controls). On March 7, 2002, the Microbiology Devices Advisory Panel (the panel) recommended that in vitro diagnostic devices for *Yersinia* spp. detection be classified into class II. The panel believed that class II with the special controls (guidance document and limitations on the distribution) would provide reasonable assurance of the safety and effectiveness of the device. After the panel meeting, FDA found one additional in vitro diagnostic device for *Yersinia* spp. detection to be substantially equivalent to another device within that type. This device has the same intended use as its predicate device but makes use of newer nucleic acid amplification technology (NAAT). While the NAAT detection devices exhibit technological differences from the preamendments *Yersinia* spp. detection devices, FDA has determined that they are as safe and effective as, and do not raise different questions of safety and effectiveness than, their predicates. (See section 513(i) of the Federal Food, Drug, and Cosmetic Act (21 U.S.C. 360c(i)).) This draft guidance document identifies the proposed classification regulation, the product code, identifies issues of safety and effectiveness that require special controls, and proposes distribution limitations. FDA believes that the special controls described in the draft guidance when combined with the general controls will be sufficient to provide reasonable assurance of the safety and effectiveness of these devices.

II. Significance of Guidance This draft guidance is being issued consistent with FDA's good guidance practices regulation (21 CFR 10.115). The draft guidance, when finalized will represent the Agency's current thinking on in vitro diagnostic devices for *Yersinia* spp. detection. It does not create or confer any rights for or on any person and does not operate to bind FDA or the public. An alternative approach may be used if such approach satisfies the requirements of the applicable statute and regulations. III. Electronic Access Persons interested in obtaining a copy of the draft guidance may do so by using the Internet. A search capability for all CDRH guidance documents is available at

<http://www.fda.gov/MedicalDevices/DeviceRegulationandGuidance/GuidanceDocuments/default.htm> .

Guidance documents are also available at <http://www.regulations.gov> . To receive Class II Special Controls Guidance Document: In Vitro Diagnostic Devices for *Yersinia* spp. Detection, you may either send an email request to dsmica@fda.hhs.gov to receive an electronic copy of the document or send a fax request to (301) 847-8149 to receive a hard copy. Please use the document number 1714 to identify the guidance you are requesting. IV. Paperwork Reduction Act of 1995

(C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because there is no necessity for such publication since the system of records will be exempt from the underlying duties to provide notification about and access to information in the system and to make amendments to and corrections of the information in the system. (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NSA will, nevertheless, continue to publish such a notice in broad generic terms, as is its current practice. (9) System identifier and name. GNSA 10, Personnel Security File. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(9)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6) , if the disclosure would compromise the objectivity or fairness of the test or examination process. (D) All portions of this system of records which fall within the scope of 5 U.S.C. 552a(k)(2) , (k)(5), and (k)(6) may be exempt from the provisions of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) , (k)(5), and (k)(6). (iii) Reasons.

(Comment 182) Several comments suggest that the number of trucking entities covered by the rule was substantially underestimated. One comment suggests that while 20 percent of the specialized carriers transport food products at any specific time, most specialized carriers transport food at one time or another. Another comment suggests that FDA's estimate of the number of covered trucking entities was low; the comment cites information obtained from the U.S. DOT that indicated close to 600,000 operating authorities on file, which includes Mexican, Canadian, and domestic carriers. Moreover, the comment suggests that if half of the general carrier population (600,000 carriers) transports food on an occasional basis, then over 300,000 companies would be affected. These numbers suggest an estimate of covered trucking facilities much larger than FDA's estimate. To support the assertion of an underestimate, the comment suggests that FDA-regulated Mexican carriers alone likely account for 12,000 facilities. Another comment states that individual transporters, not only transportation firms, will hold food while it is in transit and that transportation vehicles do not appear to be exempt from the recordkeeping requirements. (Response) FDA agrees with the concerns underlying many of these comments and revises its estimates of the number of transportation entities in a way that is consistent with the data and framework used in the PRIA. Although FDA does not dispute the comment that most specialized carriers transport food items at one time or another, the ease with which transporters enter and leave the food industry is considered in the PRIA. That analysis already accounts for the additional learning, records access, and planning costs incurred by new entrants. In the PRIA, FDA estimated that there would be approximately a 10 percent rate of entry and exit of new and existing firms for all sectors. FDA calculated the startup costs for these new entrants and added them to the compliance costs incurred by existing facilities. The County Business Pattern and NES used by FDA in the analysis include all potentially covered transporters (except foreign-based carriers that transport food in the United States), including individual carriers. However, in the PRIA, FDA neglected to include the number of establishments under North American Industry Classification System (NAICS) code 4841 for general freight trucking as well as for NAICS code 488510 for freight transportation arrangement. In the analysis of the final rule, we include entities that fall under both of these categories. The combined data from the County Business Pattern and NES contain 384,358 establishments under code 4841 for general freight

trucking. In addition, the County Business Pattern data contain 15,177 establishments for code number 488510 for freight transportation arrangement. To estimate the number of facilities under code 488510 in the NES data, we calculated (printed page 71631)

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [Docket Number DARS-2019-0020; OMB Control Number 0704-0478] **AGENCY:** Defense Acquisition Regulations System, Department of Defense (DoD). **ACTION:** Notice and request for comments regarding a proposed extension of an approved information collection requirement. **SUMMARY:** In compliance with section 3506(c)(2)(A) of the Paperwork Reduction Act of 1995, DoD announces the proposed extension of a public information collection requirement and seeks public comment on the provisions thereof. DoD invites comments on: Whether the proposed collection of information is necessary for the proper performance of the functions of DoD, including whether the information will have practical utility; the accuracy of the estimate of the burden of the proposed information collection; ways to enhance the quality, utility, and clarity of the information to be collected; and ways to minimize the burden of the information collection on respondents, including the use of automated collection techniques or other forms of information technology. The Office of Management and Budget (OMB) has approved this information collection for use through July 31, 2019. DoD proposes that OMB extend its approval for use for three additional years beyond the current expiration date. **DATES:** DoD will consider all comments received by July 22, 2019. **ADDRESSES:** You may submit comments, identified by OMB Control Number 0704-0478, using any of the following methods: · Federal eRulemaking Portal: <http://www.regulations.gov> · Follow the instructions for submitting comments. · Email: osd.dfars@mail.mil · Include OMB Control Number 0704-0478 in the subject line of the message. · Fax: 571-372-6094. · Mail: Defense Acquisition Regulations System, Attn: Ms. Kimberly Ziegler, OUSD(A&S)DPC(DARS), 3060 Defense Pentagon, Room 3B941, Washington, DC 20301-3060. Comments received generally will be posted without change to <http://www.regulations.gov> , including any personal information provided. **FOR FURTHER INFORMATION CONTACT:** Ms. Kimberly Ziegler, at 571- 372-6095. **SUPPLEMENTARY INFORMATION:** Title, Associated Form, and OMB Number: Safeguarding Covered Defense Information, Cyber Incident Reporting, and Cloud Computing; OMB Control Number 0704-0478. **Needs and Uses:** Offerors and contractors must report cyber incidents on unclassified networks or information systems, within cloud computing services, and when they affect contractors designated as providing operationally critical support, as required by statute. (

. However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. Any portions of this system which fall under the provisions of 5 U.S.C. 552a(k)(2) may be exempt from the following subsection of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (H), and (I). (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. (A) From subsection (c)(3) because disclosures from this system could interfere with the just, thorough and timely resolution of the compliant or inquiry, and possibly (printed page 14801) enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying or fabricating evidence or documents. (B) From subsection (d) because disclosures from this system could interfere with the just thorough and timely resolution of the compliant or inquiry, and possibly enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying or fabricating evidence or documents. Disclosures could also subject sources and witnesses to harassment or intimidation which jeopardize the safety and well-being of themselves and their families. (C) From subsection (e)(1) because the nature of the investigation function creates unique problems in prescribing specific parameters in a particular case as to what information is relevant or necessary. Due to close liaison and working relationships with other Federal, state, local and foreign country law enforcement agencies, information may be received which may relate to a case under the investigative jurisdiction of another government agency. It is necessary to maintain this information in order to provide leads for appropriate law enforcement purposes and to establish patterns of activity which may relate to the jurisdiction of other cooperating agencies. (D) From subsection (e)(4) (G) through (H) because this system of records is exempt from the access

provisions of subsection (d). (E) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to that individual, and record amendment procedures for this record system. (4) System identifier and name. CIG-16, DOD Hotline Program Case Files. (i) Exemption.

- Establish security responsibility (e.g. security officers) (Priority A). - Develop and maintain site security policy and procedures, including a policy for handling security incidents. - Support comprehensive security education programs for users. - Establish Forum of Incident Response Security Teams (FIRST) point of contacts. We have security policy that we are willing to share with others; it has already been shared it with NCSA. We have an incident response team (such that it is) of about three people. We maintain a contact in the local FBI office so they will not be taken by surprise if we call them for help on a computer security problem. STEINAUER; The Forum of Incident Response Security Teams (FIRST) is a cooperative effort involving a number of organizations. The concept of FIRST arose as the result of the 'Internet Worm' incident, along with a number of things that were going on in that period of time. It was clear that the basic nature of security threats had substantially changed and there were new requirements.

Are minimum performance standards for cybersecurity necessary to protect individual and collective security interests? If so, how should those minimum standards be determined and what could be done to promote their adoption? Would a collaborative government-private sector partnership be appropriate here? What are the merits of providing legal safe-harbors to those individuals and commercial entities that meet a specified minimum security level? By contrast, what would be the merits or implications of enhancing existing frameworks that hold entities accountable for failure to exercise reasonable care and that results in a loss due to inadequate security measures? Should an entity be required to implement a cybersecurity plan or meet a set of minimum security standards prior to receiving government financial guarantees or assistance? Would it be beneficial to utilize government procurement policies to stimulate cybersecurity research, development, and investment generally? How do national security requirements affect the commercial sector's adoption of cybersecurity protection measures? In addition, companies traditionally carry insurance protection to mitigate various business, natural disaster, and political risks. The growth of the Internet has begun to create a demand for new insurance products that specifically address the risk of Internet connectivity. [24] While there is growth in the adoption of cyber insurance, a compelling economic case for large scale underwriting of cyber risk insurance, apparently, has not been made. As noted above, metrics for establishing the basis for underwriting appear inadequate. (printed page 44223) What role could/should public policy play, if any, in the development of a cyber-risk measurement framework that would be useful in developing insurance products? In the face of growing risk from the increasing volume of cyber threats and vulnerabilities, what data can be made available to companies to support decisions regarding protection through the purchase of insurance products or investing more in cybersecurity protection controls? If companies were able to predictably limit financial risk through specific cyber-insurance coverage at a reliably predictable cost, how would this affect investment in cyber-security programs and infrastructure? To what extent might insurance providers create incentives or requirements for such investment? In the absence of empirical data to quantify losses from certain types of cyber incidents, what criteria could be used to most accurately and effectively determine premium costs? What, if any, quantitative relationship can be established between investment in security controls and the cost of insurance? Dated: July 22, 2010. Gary Locke, Secretary of Commerce. Patrick Gallagher, Director, National Institute of Standards and Technology. Francisco J. Sánchez, Under Secretary of Commerce for International Trade, International Trade Administration. Lawrence E. Strickling,

(Comment 13) One comment requests clarification regarding the level of recordkeeping that will be expected at each facility maintained by a vertically integrated company. The comment explains that a vertically integrated company has various facilities involved in the growing and processing of bulk ingredients as well as the manufacturing and marketing of finished products. Some of the requirements for recordkeeping could result in duplication of effort if each facility within the company is required to (printed page 71569) maintain separate records, even though the overall records are available at company headquarters or some central location. One comment requests that

the final rule clarify what is meant by the term "released" and the relationship of this term to holding legal title, or ownership of the food. Another comment suggests that FDA clarify that only at such time as the food leaves the possession and control of one firm and enters into the possession and control of another firm, whether or not via a transporter, would the recordkeeping requirement apply. The comment maintains that any other interpretation of the statute would impose a crushing burden of internal tracking systems and paperwork that would detract from most firms' abilities to do business and is well beyond the intent of the Bioterrorism Act. (Response) The records required by these regulations are those that FDA needs for inspection to identify the immediate previous sources and the immediate subsequent recipients of food. "Immediate previous source" has been defined in § 1.328 of the final rule to mean "a person who owns food or who holds, processes, packs, imports, receives, or distributes food or food packaging, and that last had an article of food before transferring it to another person." Unless otherwise exempt (i.e., a farm), a "vertically integrated company" would be required to identify the sources of all food received from its immediate previous sources. Once the vertically integrated company receives the food and keeps information on its immediate previous sources, that vertically integrated company does not need to keep additional records until it releases the food to another person. Unless otherwise exempt, at the time the vertically integrated company releases the food, it is required to identify the immediate subsequent recipients of that food. As an example, if a company buys food from its immediate previous source (company A), then the company further processes the food, holds the food, transports the food, and distributes the food to a grocery store, then the vertically integrated company would only have to keep records on its immediate previous source (company A) and its immediate subsequent recipient (grocery store). The vertically integrated company need not keep records of all the covered activities (manufacturing, processing, packing, transporting, etc.) conducted by that company while it has the food.

(6) SP 800-82r3, Guide to Operational Technology (OT) Security, September 2023 (NIST SP 800-82r3); IBR approved for § 170.4(b). (7) SP 800-115, Technical Guide to Information Security Testing and Assessment, September 2008 (NIST SP 800-115 Sept2008); IBR approved for § 170.4(b). (8) SP 800-160, Volume 2, Developing Cyber-Resilient Systems: A Systems Security Engineering Approach, Revision 1, December 2021 (NIST SP 800-160 V2R1); IBR approved for § 170.4(b). (9) SP 800-171, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, Revision 2, February 2020 (includes updates as of January 28, 2021), (NIST SP 800-171 R2); IBR approved for §§ 170.4(b) and 170.14(a) through (c). (10) SP 800-171A, Assessing Security Requirements for Controlled Unclassified Information, June 2018 (NIST SP 800-171A Jun2018); IBR approved for §§ 170.11(a), 170.14(d), 170.15(c), 170.16(c), 170.17(c), and 170.18(c). (11) SP 800-172, Enhanced Security Requirements for Protecting Controlled Unclassified Information: A Supplement to NIST Special Publication 800-171, February 2021 (NIST SP 800-172 Feb2021); IBR approved for §§ 170.4(b), 170.5(a), and 170.14(a) and (c). (12) SP 800-172A, Assessing Enhanced Security Requirements for Controlled Unclassified Information, March 2022 (NIST SP 800-172A Mar2022); IBR approved for §§ 170.4(b), 170.14(d), and 170.18(c). (b) International Organization for Standardization (ISO) Chemin de Blandonnet 8, CP 401-1214 Vernier, Geneva, Switzerland; phone: +41 22 749 01 11; website: www.iso.org/popular-standards.html. (1) ISO/IEC 17011:2017(E), Conformity assessment-Requirements for accreditation bodies accrediting conformity assessment bodies, Second edition, November 2017 (ISO/IEC 17011:2017(E)); IBR approved for §§ 170.8(b)(3), 170.9(b)(13), and 170.10(b)(4). (2) ISO/IEC 17020:2012(E), Conformity assessment-Requirement for the operation of various types of bodies performing inspection, Second edition, March 1, 2012 (ISO/IEC 17020:2012(E)); IBR approved for §§ 170.8(a), (b)(1), (b)(3) and 170.9(b)(2) and (b)(13). (3) ISO/IEC 17024:2012(E), Conformity assessment-General requirements for bodies operating certification of persons, second edition, July 1, 2012 (ISO/IEC 17024:2012(E)); IBR approved for §§ 170.8(b)(2) and 170.10(a) and (b)(4), (7), and (8). Note 1 to paragraph (b): The ISO/IEC standards incorporated by reference in this part may be viewed at no cost in "read only" format at <https://ibr.ansi.org>. § 170.3 Applicability. (a) The requirements of this part apply to: (1) All DoD contract and subcontract awardees that will process, store, or transmit information, in performance of the DoD contract, that meets the standards for FCI or CUI on contractor information systems; and, (2) Private-sector businesses or other entities comprising the CMMC Assessment and Certification Ecosystem, as specified in subpart C of this part. (printed page 83216)

We seek comment on the following matters. Do current U.S. Government (printed page 44222) product assurance requirements inhibit production of timely security components and/or security-enhanced IT products and systems? Do current assurance processes inhibit innovation? If so, what

would be the best way to improve the current U.S. product assurance scheme? What, if any, changes need to be made with respect to international product assurance institutions, standards, and processes (e.g., the Common Criteria Recognition Arrangement)? Should the Common Criteria Recognition Arrangement, the basis for international mutual recognition of cybersecurity product assurance, be expanded to include some of those countries which increasingly stray from international norms? Can useful U.S. Government or international product assurance guidelines be crafted for the current real-world software development environment? To what extent can a security oriented software assurance 'tool' be useful in software validation? What elements would be necessary to develop an effective industry-government dialogue to clarify the product assurance goals and challenges, and identify workable solutions?

7. Research and Development The U.S. Government has a continuing interest in cybersecurity research and development and has funded research on various aspects of security in computing, networking, and data processing for decades. Together with research and development programs at NIST, DOD, and several other agencies, the current unclassified Federal funding in Cyber Security and Information Assurance Research and Development is approximately \$350 million per year. One of the goals of the Comprehensive National Cybersecurity Initiative (CNCI) initiated in January 2008 is to develop 'leap-ahead' technologies that would achieve orders-of-magnitude improvements in cybersecurity. Based on this directive, in 2009, the agencies of the NITRD Program identified three initial research and development themes to exemplify and motivate future federal cybersecurity game-change research activities. [23] In addition to eliminating redundancies in federally funded cybersecurity research, identifying research gaps, and prioritizing research and development efforts, the Federal government has actively sought to create incentives for private industry and academic institutions to increase their research and development efforts. The following questions should be considered from the perspective of the Department of Commerce. How can the federal government best promote additional commercial and academic research and development in cybersecurity technology? What particular research and development areas do not receive sufficient attention in the private sector? What cybersecurity disciplines most need research and development resources (e.g.,

may be exempt pursuant to 5 U.S.C. 552a(k)(5) are subsections (d)(1) through (d)(5). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. From (d)(1) through (d)(5) because the agency is required to protect the confidentiality of sources who furnished information to the Government under an expressed promise of confidentiality or, prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. This confidentiality is needed to maintain the Government's continued access to information from persons who otherwise might refuse to give it. (8) System identifier and name. DWHS P29, Personnel Security Adjudications File. (i) Exemption. Portions of this system of records that fall within the provisions of 5 U.S.C. 552a(k)(5) may be exempt from the following subsections (d)(1) through (d)(5). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. From (d)(1) through (d)(5) because the agency is required to protect the confidentiality of sources who furnished information to the Government under an expressed promise of confidentiality or, prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. This confidentiality is needed to maintain the Government's continued access to information from persons who otherwise might refuse to give it. This exemption is limited to disclosures that would reveal the identity of a confidential source. At the time of the request for a record, a determination will be made concerning whether a right, privilege, or benefit is denied or specific information would reveal the identity of a source. (9) System identifier and name. JS004SECDIV, Joint Staff Security Clearance Files. (i) Exemption. Portions of this system of records are exempt pursuant to the provisions of 5 U.S.C. 552a(k) (5) from subsections 5 U.S.C. 552a(d)(1) through (d)(5) . (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. From subsections (d)(1) through (d)(5) because the agency is required to protect the confidentiality of sources who furnished information to the Government under an expressed promise of confidentiality or, prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. This confidentiality is needed to maintain the Government's continued access to information from persons who otherwise might refuse to give it. This exemption is limited to disclosures that would reveal the identity of a confidential source. At the time of the request for a record, a determination will be made concerning whether a right, privilege, or benefit is denied or specific information would reveal the identity of a source. (10) System identifier and name. DFMP 26, Vietnamese Commando Compensation Files. (i) Exemption. Information classified under E.O. 12958 , as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (ii) Authority. 5 U.S.C. 552a(k)(1) . (iii) Reasons. From subsection 5 U.S.C. 552a(d)

OMB approved publishing the CMMC rule as a Proposed Rule. It has undergone a required notice-and-comment process to give the public an opportunity to submit comments. The Proposed Rule and the comments received informed the final rule. Issues with the Federal Register or www.regulations.gov functionality for submitting comments via attachment of pdf or other file type were raised with the appropriate help desk and resolved before conclusion of the public comment period. The public comment period for this rule permitted review and feedback from any member of the public. This rule follows the format and includes all sections required in OMB guidelines for formal rulemaking. The length of this rule is necessary to ensure all affected parties have sufficient information to understand and comply with the rule. Federal Register page numbers are visible when viewing the PDF version of the rule published Tuesday, December 26, 2023 (88 FR 89058 ; www.govinfo.gov/content/pkg/FR-2023-12-26/pdf/2023-27280.pdf). Material published in the Federal Register contains numerous sections, including portions that do not amend the CFR. Specifically, the preamble for this rule, is written in a summary format and is not intended to provide the detailed information that is in the regulatory text. DoD declines to delete reserved sections because the editorial standard for orderly codification is that for every (a) there must be at least a (b), and for every (1) there must be at least a (2), etc. 'Reserved' meets this standard when there is no additional text required. The DoD declined to make other administrative changes, because the recommendations did not result in a substantive change. One commenter correctly identified that the initial 32 CFR part 170 CMMC Program proposed rule included discussion and analysis of comments made against prior publication of a 48 CFR CMMC interim final rule. The decision to include that material was made for the public's convenience and to facilitate greater understanding of the 32 CFR part 170 CMMC Program proposed rule and the CMMC Program. Codification of the CMMC Program requires publication of both the 32 CFR part 170 CMMC Program final rule and the 48 CFR part 204 CMMC Acquisition final rule. Each of those final rules will include a discussion and analysis of public comments received during their respective comment periods. The DoD CIO worked in conjunction with OUSD(A&S) to ensure that the 32 CFR part 170 CMMC Program rule and the 48 CFR part 204 CMMC Acquisition rule are in sync. The preamble is not regulatory text. The preamble includes a response to the significant, relevant issues raised in previous public comments on the original CMMC program. DoD declines to adopt recommendations to move content from the 32 CFR part 170

3.5.2 Provide Recommendations and Implementation Plan The Contractor shall prepare a recommendations report on whether <product name> will meet the organization requirement.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. - 56 of 90 agencies were using IoT, especially to control or monitor systems, control access to facilities, and track physical assets (vehicles, property). - 25 agencies were currently using IoT and planned to expand their use. - 13 agencies were neither using nor planning to use IoT, based on lack of return on investment, internal administrative hurdles, or the lack of a business case.

Maintenance. Review and test the effectiveness of the technology assets and/or technical controls required by this paragraph (d) at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. (e) Standard: Integrity. Deploy technical controls to protect electronic protected health information from improper alteration or destruction, both at rest and in transit; and review and test the effectiveness of such technical controls at least once every 12 months or in response to environmental or operational changes, whichever is more frequent, and modify as reasonable and appropriate. (f) Standard: Authentication ·(1) General. Deploy technical controls to verify that a person or technology asset seeking access to electronic protected health information and/or the covered entity's or business associate's relevant electronic information systems is the one claimed. (2) Implementation specifications ·(i) Information access management policies. Deploy technical controls in accordance with the covered entity's or business associate's information access management policies and procedures under §.164.308(a)(10), including technical controls that

require users to adopt unique passwords that are consistent with the current recommendations of authoritative sources. (ii) Multi-factor authentication. (A) Deploy multi-factor authentication to all technology assets in the covered entity's or business associate's relevant electronic information systems to verify that a person seeking access to the relevant electronic information system(s) is the user that the person claims to be. (B) Deploy multi-factor authentication for any action that would change a user's privileges to the covered entity's or business associate's relevant electronic information systems in a manner that would alter the user's ability to affect the confidentiality, integrity, or availability of electronic protected health information. (iii) Exceptions. Deployment of multi-factor authentication is not required in any of the following circumstances. (A) The technology asset in use does not support multi-factor authentication, and the covered entity or business associate establishes and implements a written plan to migrate electronic protected health information to a technology asset that supports multi-factor authentication within a reasonable and appropriate period of time.

(q) The Chief, National Guard Bureau, is authorized to act on requests for all personnel and medical records of retired, separated, discharged, deceased, and active Army National Guard military personnel, including technician personnel, unless such records clearly fall within another Denial Authority's responsibility. This authority includes, but is not limited to, National Guard organization and training files; plans, operations, and readiness files, policy files, (printed page 24509) historical files, files relating to National Guard military support, drug interdiction, and civil disturbances; construction, civil works, and ecology records dealing with armories, facilities within the States, ranges, etc.; Equal Opportunity investigative records; aviation program records and financial records dealing with personnel, operation and maintenance, and equipment budgets. (r) The Chief, Army Reserve and Commander, U.S. Army Reserve Command are authorized to act on requests for all personnel and medical records of retired, separated, discharged, deceased, and reserve component military personnel, and all U.S. Army Reserve (USAR) records, unless such records clearly fall within another Denial Authority's responsibility. Records under the responsibility of the Chief, Army Reserve and the Commander, U.S. Army Reserve Command include records relating to USAR plans, policies, and operations; changes in the organizational status of USAR units; mobilization and demobilization policies, active duty tours, and the Individual Mobilization Augmentation program; and all other Office of the Chief, Army Reserve (OCAR) records and Headquarters, U.S. Army Reserve Command records. (s) The Commander, United States Army Materiel Command (AMC) is authorized to act on requests for the records of AMC headquarters and to subordinate commands, units, and activities that relate to procurement, logistics, research and development, and supply and maintenance operations. (t) The Provost Marshal General is authorized to act on all requests for provost marshal activities and law enforcement functions for the Army, all matters relating to police intelligence, physical security, criminal investigations, corrections and internment (to include confinement and correctional programs for U.S. prisoners, criminal investigations, provost marshal activities, and military police support. The Provost Marshal General is responsible for the Office of Security, Force Protection, and Law Enforcement Division and is the functional proponent for AR 190-series (Military Police) and 195-series (Criminal Investigation), AR 630-10 Absent Without Leave, Desertion, and Administration of Personnel Involved in Civilian Court Proceedings, and AR 633-30, Military Sentences to Confinement.

Limits on the use of organization -controlled portable storage devices in external systems include complete prohibition of the use of such devices or restrictions on how the devices may be used and under what conditions the devices may be used. Note that while -external- typically refers to outside of the organization's direct supervision and authority that is not always the case. Regarding the protection of CUI across an organization, the organization may have systems that process CUI and others that do not. Among the systems that process CUI there are likely access restrictions for CUI that apply between systems . Therefore, from 52 NIST SP 800-171A, p. 18. 53 NIST SP 800-171 Rev. 2, p. 16.

The Department requests comment on the foregoing proposals, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular: a. Whether every 12 months is an appropriate frequency for review of a regulated entity's written policies and procedures for physical safeguards. If not, please explain. b. Whether the written policies and procedures for physical safeguards should be reviewed at different intervals, based on the specific standard or implementation specification. If so, please explain. c. Whether the Department should include additional examples in regulatory text at proposed 45 CFR

164.310(a)(2)(iv) of physical components of a facility related to security for which there should be written policies and procedures to document repairs and modifications. d. Whether the standard at proposed 45 CFR 164.310(d)(1) and its associated implementation specifications at paragraph (d)(2) should apply to technology assets that do not maintain ePHI, but do access the regulated entity's relevant electronic information systems. F. Section 164.312·Technical Safeguards 1. Current Provisions Section 164.312 includes five standards for technical safeguards, which are the requirements concerning the implementation of technology and technical policies and procedures to protect the confidentiality, integrity, and availability of ePHI and related information systems. A regulated entity must comply with the standards for technical safeguards in accordance with 45 CFR 164.306(c) , the provision that describes the general rules for the security standards. Under 45 CFR 164.312(a)(1) , a regulated entity is required to establish policies and procedures for electronic information systems to allow access only to those persons or software programs that have been granted access rights as specified in 45 CFR 164.308(a)(4) . Regulated entities may comply with this standard by implementing a combination of access control methods and technical controls, consistent with the implementation specifications for this standard. The Security Rule does not identify a specific access control method or technology to implement. Regardless of the technology or information system used, access controls should be appropriate for the workforce member's role and/or function. [659] For example, a workforce member responsible for monitoring and administering information systems with ePHI, such as an administrator or a superuser, [660] should only have access to ePHI as appropriate for their role and/or job function. The implementation specifications that provide instructions for satisfying the access control standard are found at 45 CFR 164.312(a)(2) . Two are required and two are addressable. [661] The implementation specifications address unique user identifiers, [662] emergency access procedures, [663] automatic logoff, [664] and encryption and decryption. [665] The implementation (printed page 963)

A configuration of 16 rounds in series is the "guts" of the algorithm; the only significant difference is in the key schedule (Figure 6). This analysis model is based on a 768 bit key, each 48 bit segment is used as a key for one of the 16 rounds. This series configuration is invertible. The average number of corresponding plaintext-ciphertext pairs required to recover a key is still four. In the DES algorithm the beginning and ending permutations are now included with the previous configuration. The effect of the key schedule is that the 16 previous independent operations are no longer independent of one another. The number of plaintext-ciphertext pairs that must be tested to recover a key uniquely is unknown, but may well be larger than one. The statistical properties of the output in the complete algorithm, considered as a pseudorandom number generator, are substantially improved over the properties exhibited by the output of the sixteen independent-operation model

(C) From subsections (d) and (f) because requiring DSS to grant access to records and agency rules for access and amendment of records would unfairly impede the agency's investigation of allegations of unlawful activities. To require DSS to confirm or deny the existence of a record pertaining to a requesting individual may in itself provide an answer to that individual relating to an on-going investigation. The investigation of possible unlawful activities would be jeopardized by agency rules requiring verification of record, disclosure of the record to the (printed page 14780) subject, and record amendment procedures. (5) System identifier and name. V5-04, Counterintelligence Issues Database (CII-DB). (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958 , as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (C) Records maintained in connection with providing protective services to the President and other individuals under 18 U.S.C. 3506 , may be exempt pursuant to 5 U.S.C. 552a(k)(3) . (D) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (E) Any portion of this system that falls within the provisions of 5 U.S.C. 552a(k)(1) , (k)(2), (k)(3) and (k)(5) may be exempt from the following subsections (c)(3); (d)(1) through

(d)(5); (e)(1); (e)(4)(G), (H), and (I); and (f). (ii) Authority. 5 U.S.C. 552a(k)(1) , (k)(2), (k)(3) and (k)(5). (iii) Reasons. (A) From subsection (c)(3) because giving the individual access to the disclosure accounting could alert the subject of an investigation to the existence and nature of the investigation and reveal investigative or prosecutive interest by other agencies, particularly in a joint-investigation situation. This would seriously impede or compromise the investigation and case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate with the investigators; lead to suppression, alteration, fabrication, or destruction of evidence; and endanger the physical safety of confidential sources, witnesses, law enforcement personnel and their families.

<https://www.himss.org/sites/hde/files/media/file/2024/03/01/2023-himss-cybersecurity-survey-x.pdf> . Back to Citation 200. Id. at 16; Generative AI is a type of software that uses statistical models that generalize the patterns and structures of existing data to either reorganize existing data or create new content. Risk In Focus: Generative A.I. And The 2024 Election Cycle, Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security, https://www.cisa.gov/sites/default/files/2024-05/Consolidated_Risk_in_Focus_Gen_AI_ElectionsV2_508c.pdf . Back to Citation 201. 2023 HIMSS Healthcare Cybersecurity Survey, supra note 199, p. 22. Back to Citation 202. See Lizzie Roehrs, CSL Professor explores DNA as data storage, University of Illinois Urbana-Champaign The Grainger College of Engineering Coordinated Science Laboratory (Aug. 25, 2020), <https://csl.illinois.edu/news-and-media/csl-professor-explores-dna-data-storage> ; Cheng Kai Lim, et al., A biological camera that captures and stores images directly into DNA, nature communications (July 3, 2023), <https://www.nature.com/articles/s41467-023-38876-w> ; Devasier Bennet, et al., Current and emerging opportunities in biological medium-based computing and digital data storage, Nano Select, p. 883 (May 2022), <https://doi-org.hhsnih.idm.oclc.org/10.1002/nano.202100275> . Back to Citation 203. 88 FR 75191 (Nov. 1, 2023). Back to Citation 204. Id. at 75214. Back to Citation 205. See HHS Artificial Intelligence (AI) Strategy: AI Council & AI Community of Practice, U.S. Department of Health and Human Services (June 6, 2024), <https://www.hhs.gov/programs/topic-sites/ai/strategy/index.html> ; About the HHS Office of the Chief Artificial Intelligence Officer (OCAIO), U.S. Department of Health and Human Services (June 6, 2024), <https://www.hhs.gov/programs/topic-sites/ai/ocaio/index.html> ; see also Advancing Governance, Innovation, and Risk Management for Agency Use of Artificial Intelligence, M-24-10, Office of Management and Budget, Executive Office of the President (Mar. 28, 2024), <https://www.whitehouse.gov/wp-content/uploads/2024/03/M-24-10-Advancing-Governance-Innovation-and-Risk-Management-for-Agency-Use-of-Artificial-Intelligence.pdf> . Back to Citation 206. See, e.g., 89 FR 37522 , 37642 (May 6, 2024) and 89 FR 1192 , 1244 (Jan. 9, 2024). Back to Citation 207. John Riggi, The importance of cybersecurity in protecting patient safety, American Hospital Association Center for Health Innovation, <https://www.aha.org/center/cybersecurity-and-risk-advisory-services/importance-cybersecurity-protecting-patient-safety>

A key difference between the DFARS 252.204-7012 and CMMC Level 2 requirements is that compliance with NIST SP 800-171 under DFARS 252.204-7012 has not been consistently verified. Under CMMC, compliance will be checked by independent third-party assessors certified by DoD. When this 32 CFR CMMC Program rule is finalized, solicitations for defense contracts involving the processing, storing, or transmitting of FCI or CUI on a non-Federal system will, in most cases, have a CMMC level and assessment type requirement a contractor must meet to be eligible for a contract award. CMMC-related contractual processes will be addressed in DoD's DFARS Case 2019-D041, Assessing Contractor Implementation of Cybersecurity Requirements, which will be proposed by the Department in a separate rulemaking. [12] This rule establishes the CMMC Program and defines requirements both in general and based on the specific CMMC level and assessment type required by the contract and applicable subcontract. Each CMMC level and assessment type is described. 1. Contracts or Subcontracts With a CMMC Level 1 Self-Assessment Requirement a. Security Requirements For CMMC Level 1, contractors and applicable subcontractors are already required to implement the 15 security requirements currently required by the FAR clause 52.204-21. (printed page 89060) b. Assessment Requirements (New) At Level 1, CMMC adds a requirement for contractors and applicable subcontractors to verify through self-assessment that all applicable security requirements outlined in FAR clause 52.204-21 have been implemented. This self-assessment must be performed annually and the results must be entered electronically in the Supplier Performance Risk System (SPRS) (see §.170.15 for details on CMMC Level 1 Self-Assessment requirements and procedures, and specifically

§ 170.15(a)(1)(i) for the information collection). c. Affirmation Requirements (New) A senior official from the prime contractor and any applicable subcontractor will be required to annually affirm continuing compliance with the specified security requirements. Affirmations are entered electronically in SPRS (see § 170.22 for details on Affirmation requirements and procedures). 2. Contracts or Subcontracts With a CMMC Level 2 Self-Assessment Requirement a. Security Requirements For CMMC Level 2, contractors and applicable subcontractors are already required to implement the 110 security requirements currently required by the DFARS clause 252.204-7012, which are aligned with NIST SP 800-171 Rev 2. b. Assessment Requirements (New)

(15) Neither disclose nor allow any CAICO training support service providers, as applicable, to disclose CMMC data or metrics related to authorization or certification activities to any entity other than the Accreditation Body and DoD, except as required by law. (16) Require retraining and redesignation of PIs upon significant change to DoD's CMMC Program requirements. Require retraining and recertification of CCPs, CCAs, and CCIs upon significant change to DoD's CMMC Program requirements, as determined by the DoD or the CAICO. (17) Require CMMC Ecosystem members to report to the CAICO within 30 days of convictions, guilty pleas, or no contest pleas to crimes of fraud, larceny, embezzlement, misappropriation of funds, misrepresentation, perjury, false swearing, conspiracy to conceal, or a similar offense in any legal proceeding, civil or criminal, whether or not in connection with activities that relate to carrying out their role in the CMMC Ecosystem.

§ 170.11 CMMC Certified Assessor (CCA). (a) Roles and responsibilities. CCAs, in support of a C3PAO, conduct Level 2 certification assessments of OSCs in accordance with NIST SP 800-171A Jun2018 (incorporated by reference, see § 170.2), the assessment processes defined in § 170.17, and the scoping requirements defined in § 170.19(c). CCAs must meet all of the requirements set forth in paragraph (b) of this section. A CCA may conduct Level 2 certification assessments and participate on a C3PAO Assessment Team. (b) Requirements. CCAs shall: (1) Obtain and maintain certification from the CAICO in accordance with the requirements set forth in § 170.10. Certification is valid for 3 years from the date of issuance. (2) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17). (3) Complete a Tier 3 background investigation resulting in a determination of national security eligibility. This Tier 3 background investigation will not result in a security clearance and is not being executed for the purpose of government employment. The Tier 3 background investigation is initiated using the Standard Form (SF) 86 (www.gsa.gov/reference/forms/questionnaire-for-national-security-positions). These positions are designated as non-critical sensitive with a risk designation of 'Moderate Risk' in accordance with 5 CFR 1400.201(b) and (d) and the investigative requirements of 5 CFR 731.106(c)(2) . (4) Meet the equivalent of a favorably adjudicated Tier 3 background investigation when not eligible for a Tier 3 background investigation. DoD will determine the Tier 3 background investigation equivalence for use with the CMMC Program only. (5) Provide all documentation and records in English.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [OMB Control Number 0704-0225; Docket Number DARS-2016-0041] AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Notice and request for comments regarding a proposed revision of an approved information collection requirement. SUMMARY: In compliance with section 3506(c)(2)(A) of the Paperwork Reduction Act of 1995 (44 U.S.C. chapter 35), DoD announces the proposed revision of a public information collection requirement and seeks public comment on the provisions thereof. DoD invites comments on: (a) Whether the proposed collection of information is necessary for the proper performance of the functions of DoD, including whether the information will have practical utility; (b) the accuracy of the estimate of the burden of the proposed information collection; (c) ways to enhance the quality, utility, and clarity of the information to be collected; and (d) ways to minimize the burden of the information collection on respondents, including the use of automated collection techniques or other forms of information technology. The Office of Management and Budget (OMB) has approved this information collection for use through March 31, 2017. DoD proposes that OMB extend its approval for use for three additional years beyond the current expiration date. DATES: DoD will consider all comments received by December 19, 2016. ADDRESSES: You may submit comments, identified by OMB Control Number (printed page 71712)

0704-0225, using any of the following methods: Federal eRulemaking Portal: <http://www.regulations.gov> . Follow the instructions for submitting comments. Email: osd.dfars@mail.mil . Include OMB Control Number 0704-0225 in the subject line of the message. Fax: 571-372-6094. Mail: Defense Acquisition Regulations System, Attn: Ms. Carrie Moore, OUSD (AT&L) DPAP (DARS), 3060 Defense Pentagon, Room 3B941, Washington, DC 20301-3060. Comments received generally will be posted without change to <http://www.regulations.gov> , including any personal information provided. FOR FURTHER INFORMATION CONTACT: Ms. Carrie Moore, at 571-372-6093. The information collection requirements addressed in this notice are available on the World Wide Web at: <http://www.acq.osd.mil/dpap/dars/dfarspgi/current/index.html> . Paper copies are available from Ms. Carrie Moore, OUSD (AT&L) DPAP (DARS), 3060 Defense Pentagon, Room 3B941, Washington, DC 20301-3060. SUPPLEMENTARY INFORMATION: Title and OMB Number:

) A potential contractor which is located in the United States or [insert applicable country] has been approved for access to classified information and material by the USG or [insert applicable country] security authorities; or (2) If located in a third country, prior written USG consent is obtained. (G) Upon completion of the contract, all classified material furnished or generated pursuant to the contract will be [insert whether the material is to be returned or destroyed, or provide other instructions]. (H) The recipient contractor will insert terms that substantially conform to the language of these provisions, including this one, in all subcontracts under this contract that involve access (printed page 83350) to classified information furnished or generated under this contract. (c) FGI. (1) General. The contractor will notify the csa when awarded contracts by a foreign interest that will involve access to classified information. The csa will oversee and ensure implementation of the security requirements of the contract on behalf of the foreign government, including the establishment of channels for the transfer of classified material. (2) Contract security requirements. The foreign entity that awards a classified contract is responsible for providing appropriate security classification guidance and any security requirements clauses. The contractor will report to the CSA when a foreign entity fails to provide classification guidance. (3) Marking foreign government classified material. Foreign government classified material will be marked in accordance with § 117.14(l). (4) Foreign Government RESTRICTED Information and In Confidence Information. Foreign government RESTRICTED information and in confidence information will be marked in accordance with § 117.14(m). (5) Marking U.S. documents containing FGI. U.S. documents containing FGI will be marked in accordance with § 117.14(n). (6) Marking documents prepared for foreign governments. Marking documents prepared for foreign governments will be marked in accordance with § 117.14(o). (7) Storage and control. Contractors will store foreign government material and control access generally in the same manner as U.S. classified material of an equivalent classification. Contractors will store foreign government material in a manner that will separate it from other material. Separation can be accomplished by establishing distinct files in a storage container or on an information system. (8) Disclosure and use limitations. (i) FGI is provided by the foreign government to the United States. The contractor will: (A) Not disclose FGI to nationals of a third country, or to any other third party, or use it for any purpose other than that for which it was provided without the prior written consent of the originating foreign government. (B) Submit requests for other uses or further disclosure to the GCA for U.S. contracts, and through the CSA for direct commercial contracts.

(4) Obtain access to DoD's secure voice and data transmission systems supporting the voluntary DIB CS Program. Dated: April 25, 2023. Aaron T. Siegel, Alternate OSD Federal Register Liaison Officer, Department of Defense. Footnotes 1. <https://www.ecfr.gov/current/title-48/chapter-2/subchapter-H/part-252/subpart-252.2/section-252.204-7012> . Back to Citation 2. <https://obamawhitehouse.archives.gov/the-press-office/2013/02/12/presidential-policy-directive-critical-infrastructure-security-and-resil> . Back to Citation 3. 77 FR 27615 , May 11, 2012 (<https://www.govinfo.gov/content/pkg/FR-2012-05-11/pdf/2012-10651.pdf>). Back to Citation 4. 78 FR 62430 , October 22, 2013 (<https://www.govinfo.gov/content/pkg/FR-2013-10-22/pdf/2013-24256.pdf>). Back to Citation 5. 80 FR 59581 , October 2, 2015 (<https://www.govinfo.gov/content/pkg/FR-2015-10-02/pdf/2015-24296.pdf>). Back to Citation 6. The National Security Agency administers COMSEC accounts. Back to Citation 7. 81 FR 68312 , October 4, 2016 (<https://www.govinfo.gov/content/pkg/FR-2016-10-04/pdf/2016-23968.pdf>). Back to Citation 8. 32 CFR 236.2 defines cleared defense contractor to mean a subset of contractors cleared under the National Industrial Security Program (NISP) who have classified contracts with the DoD. Back to Citation 9. The DoD has established the External Certification

Authority (ECA) program to support the issuance of DoD-approved certificates to industry partners and other external entities and organizations. The ECA program is designed to provide the mechanism for these entities to securely communicate with the DoD and authenticate to DoD Information Systems. [<https://public.cyber.mil/eca/>]. Back to Citation 10. Entities (including companies and academic institutions) engaged in providing goods or services to the U.S. Government involving access to or creation of classified information may be granted a Facility Clearance (FCL). The Defense Counterintelligence and Security Agency (DCSA) processes, issues, and monitors the continued eligibility of entities for an FCL. [<https://www.dcsa.mil/mc/isd/fc/>]. Back to Citation 11. Applicants to the DIB CS Program submit an application from <https://dibnet.dod.mil> . Once a company has been verified, the Framework Agreement is made available for review. Back to Citation 12. <https://www.ecfr.gov/current/title-32/subtitle-A/chapter-II/subchapter-D/part-117> . Back to Citation 13. This is based upon the 2022 General Schedule (GS) pay scale for a GS-9 Step 5 and is adjusted upward by 100% to adjust for overhead and benefits. Back to Citation [FR Doc. 2023-09021 Filed 5-2-23; 8:45 am] BILLING CODE 5001-06-P

The Department anticipates that regulated entities would need to develop new or modified policies and procedures for the proposed new requirements to obtain or provide verification of business associates' compliance with the Security Rule's requirements for technical safeguards, conducting a Security Rule compliance audit, and reporting the activation of a contingency plan, as well as other proposed changes, depending on the regulated entities' existing policies and procedures. The Department estimates that the costs associated with developing such policies and procedures would be the labor of a computer and information systems manager for an average of 3.5 hours (with 2.5 hours as a low estimate and 6 hours as a high estimate, depending on the number of entities with written policies and procedures, and their degree of specificity). This would result in total annual costs of \$1,108,432,416 [= 1,822,600 regulated entities × 3.5 hours × \$173.76], with a low estimated total of \$791,737,440 [= 1,822,600 regulated entities × 2.5 hours × \$173.76] and high estimated total of \$1,900,169,856 [= 1,822,600 regulated entities × 6 hours × \$173.76]. The existing rule requires updates to policies and procedures in response to environmental or operational changes affecting the security of the ePHI, and as a result, the Department is estimating additional costs for new policies related to this proposed rule as an incremental increase.

I. Costs Associated With Training Workforce Members The Department anticipates that regulated entities would be able to incorporate new content into existing Security Rule training programs and that the costs associated with doing so would be attributed to the labor of a training specialist for an estimated 2 hours for total annual costs of \$252,247,840 [= 1,822,600 regulated entities × 2 hours × \$69.20]. The low estimate for this activity is \$126,123,920 [= 1,822,600 regulated entities × 1 hour × \$69.20], and the high estimate is \$378,371,760 [= 1,822,600 regulated entities × 3 hours × \$69.20]. Many of the changes in the NPRM require the (printed page 1000) adoption of standard cybersecurity practices as applied specifically to address the confidentiality, integrity, and availability of ePHI, so we expect that an information security analyst would be familiar with this content. These estimated costs would address any required revisions to training for workforce members within the first year of compliance with a final rule. Any further recurring component is likely to be implemented into regularly scheduled employee training and thus would not be directly attributable to the proposals in this NPRM.

m. Revising Business Associate Agreements The NPRM proposes to provide a transition period in proposed 45 CFR 164.318

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204, 209, 212, and 252 [Docket DARS-2019-0065] RIN 0750-AK58 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to remove a provision that is no longer necessary, pursuant to action taken by the Regulatory Reform Task Force. DATES: Effective October 31, 2019. FOR FURTHER INFORMATION CONTACT: Ms. Carrie Moore, telephone 571-372-6093. SUPPLEMENTARY INFORMATION: I. Background DoD is amending the DFARS to remove DFARS provision 252.204-7013, Limitations on the Use or Disclosure of Information by Litigation Support Contractors, its associated prescription at 204.7403 and related text at 209.505-4(b)(ii) and 212.301. This provision is included in solicitations for the acquisition of litigation support

services. The provision includes a representation that, by submission of its offer, the offeror agrees to handle and protect all litigation information and documentation as described in the provision, indemnify the Government from any liability or claim that arises from the offeror's misuse of the litigation information, and ensure its employees are subject to the same use and nondisclosure obligations stated in the provision prior to accessing any litigation information. The provision also notifies offerors that third parties holding proprietary rights or any other legally protectable interest in the provided litigation information have the right of direct action against the offeror for any unauthorized use or disclosure by the offeror. DFARS provision 252.204-7013 is unnecessary. The same information is provided to offerors by including DFARS clause 252.204-7014, Limitations on the Use or Disclosure of Information by Litigation Support Contractors, in a solicitation. II. Discussion and Analysis DFARS clause 252.204-7014 implements the authority and requirements of 10 U.S.C. 129d

The DIB CS/IA program focuses on sharing cyber security related information and minimizes the collection of information from participating DIB companies, seeking only the information that is necessary to support this cyber security program. The PIA for the DIB CS/IA program details the comprehensive processes to safeguard PII. The operational implementation of the DIB CS/IA program receives PII from DIB Companies in two ways: (i) For program administration and management purposes, the DIB companies share with DoD the typical business contact information for its personnel that are serving as company points of contact for the program activities or specific cyber incidents; and (ii) for cyber incident response and analysis purposes, DIB companies may share PII as a necessary part of the information that they have determined is relevant to cyber incident response, analysis, or damage assessment. In addition, DIB companies are prohibited from sharing any information unless they have determined that the information has been lawfully collected and is authorized to be shared with DoD. The DIB CS/IA Program restricts access to such PII and attribution information only to those authorized personnel who have a need-to-know such information for duties in support of the DIB CS/IA Program and are subject to strict nondisclosure obligations. The PII is only maintained as long as necessary for DIB CS/IA Program activities, and is managed and disposed of in accordance with applicable records management requirements. No change is made to the rule. Comment: One comment stated that the rule allows a number of private companies to sell and share private citizens' data including to other Governments, including any data that 'transits' any government system. Response: The voluntary DIB CS/IA program does not authorize participating companies to sell any information, to anyone, in any context whatsoever. The program also does not authorize DIB companies to share any information with anyone other than program participants. The program does not permit the sharing of information with any governments other than authorized U.S. Government participants. No change is made to the rule. Comment: One comment stated that the rule does not properly ensure implementation of the new Controlled Unclassified Information (CUI) framework from Executive Order 13556 into its treatment of covered defense information. Response: As stated in the Background Section above, the program is designed to ensure consistency with and support for, federal activities related to the handling and safeguarding of controlled unclassified information that are being led by the National Archives and Records Administration pursuant to Executive Order 13556. As CUI implementation evolves in the Government, the rule will be modified as necessary to ensure compliance. No change is made to the rule. Comment:

Comments which suggest that enrollment in the DoD's DIB CS Program can be an alternative means of meeting the objectives of CMMC misinterpret the services that the DIB CS Program provides. The DIB CS Program does not provide any mechanism for verifying whether those participants have secured their contractor owned information systems to the standards required by DFARS clause 252.204-7012. Likewise, the recommended NSA cybersecurity offerings also do not provide the same verification mechanism that CMMC will provide. CMMC Program requirements apply to contractor-owned information systems that process, store, or transmit FCI and CUI. Hardware and software approving authorities for GFE are not relevant to this CMMC rule. The DoD declined to adopt the recommendation to provide GFE to DIB contractors to maintain security, ownership of data and support Clinger-Cohen Act compliance. Some comments received reflect a misinterpretation of the cost estimates that accompany this rule, which are intended to inform the rulemaking process. The cost estimates are not indicative of a funded budget line which could be reprogrammed to fund a new agency to meet the objectives of the CMMC Program. Comments recommending that funding be appropriated (by Congress) to provide the DIB with security solutions are beyond the scope of this rule. b. Alternate Standards Comment: One commenter recommended aligning requirements to DoD policies rather than to NIST standards and relying on FISMA compliance assessments in lieu of the CMMC model. Another commenter

recommended the DoD and NIST work with other international standards organizations to incorporate CMMC requirements (really NIST standards) into existing ISO/IEC and CMMI standards. In general, these commenters recommended DoD accept alternate assessments conducted against alternate standards by assessors with alternate training and qualifications. They further recommended that DoD issue an RFI seeking recommendation of alternate third-party assessment schemes. One commenter recommended the rule be modified to require that contracts with a CMMC level 3 requirement also require use of a FedRAMP moderate or higher CSP, and that contracts with a CMMC level 2 requirement permit use of CSPs with either FedRAMP Moderate authorization (or higher) or CMMC level 2 or 3 certification assessment. Response: CMMC is based on the executive branch's CUI Program as the authoritative source, as codified in 32 CFR part 2002. The definition of CUI and general requirements for its safeguarding are included in 32 CFR 2002.4 and 2002.14, respectively. 32 CFR 2002.14(h)(2) specifically requires that Agencies must use NIST SP 800-171 when establishing security requirements to protect CUI's confidentiality on non-Federal information systems. . . . The CMMC (printed page 83157)

(2) The requirements for defining the CMMC Assessment Scope for CMMC Levels 1, 2, and 3 are set forth in this section. Additional guidance regarding scoping can be found in the guidance documents listed in paragraphs (e) through (g) of appendix A to this part. (b) CMMC Level 1 scoping. Prior to performing a Level 1 self-assessment, the OSA must specify the CMMC Assessment Scope. (1) Assets in scope for Level 1 self-assessment. OSA information systems which process, store, or transmit FCI are in scope for CMMC Level 1 and must be self-assessed against applicable CMMC security requirements. (2) Assets not in scope for Level 1 self-assessment. (i) Out-of-Scope Assets. OSA information systems which do not process, store, or transmit FCI are outside the scope for CMMC Level 1. An endpoint hosting a VDI client configured to not allow any processing, storage, or transmission of FCI beyond the Keyboard/Video/Mouse sent to the VDI client is considered out-of-scope. There are no documentation requirements for out-of-scope assets. (ii) Specialized Assets. Specialized Assets are those assets that can process, store, or transmit FCI but are unable to be fully secured, including: Internet of Things (IoT) devices, Industrial Internet of Things (IIoT) devices, Operational Technology (OT), Government Furnished Equipment (GFE), Restricted Information Systems, and Test Equipment. Specialized Assets are not part of the Level 1 CMMC Assessment Scope and are not assessed against CMMC security requirements. (3) Level 1 self-assessment scoping considerations. To scope a Level 1 self-assessment, OSAs should consider the people, technology, facilities, and External Service Providers (ESP) within its environment that process, store, or transmit FCI. (c) CMMC Level 2 Scoping. Prior to performing a Level 2 self-assessment or Level 2 certification assessment, the OSA must specify the CMMC Assessment Scope. (1) The CMMC Assessment Scope for CMMC Level 2 is based on the specification of asset categories and their respective requirements as defined in table 3 to this paragraph (c)(1). Additional information is available in the guidance document listed in paragraph (f) of appendix A to this part. Table 3 to § 170.19 (c)(1) CMMC Level 2 Asset Categories and Associated Requirements

Asset category	Asset description	OSA requirements	CMMC assessment requirements
Assets that are in the Level 2 CMMC Assessment Scope	Controlled Unclassified Information (CUI) Assets	Assets that process, store, or transmit CUI	Document in the asset inventory
	Document asset treatment in the System Security Plan (SSP).	Document in the network diagram of the CMMC Assessment Scope.	Prepare to be assessed against CMMC Level 2 security requirements.
	Assess against all Level 2 security requirements.	Security Protection Assets	Assets that provide security functions or capabilities to the OSA's CMMC Assessment Scope

(1) Obtain and maintain certification from the CAICO in accordance with the requirements set forth in § 170.10. Certification is valid for 3 years from the date of issuance. (2) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17). (3) Provide all documentation and records in English. (4) Provide the Accreditation Body and the CAICO with the most up-to-date and accurate information detailing their qualifications, training experience, professional affiliations, and certifications, and, upon reasonable request, submit documentation verifying this information. (5) Not provide CMMC consulting services while serving as a CMMC instructor. (6) Not participate in the development of exam objectives and/or exam content or act as an exam proctor while at the same time serving as a CCI. (7) Keep confidential all information obtained or created during the performance of CMMC training activities, including trainee records, except as required by law. (8) Not disclose any CMMC-related data or metrics to anyone without prior coordination with and approval from DoD. (9) Notify the Accreditation Body or the CAICO if required by law or authorized by contractual

commitments to release confidential information. (10) Not share with anyone any CMMC training-related information not previously publicly disclosed. § 170.13 CMMC Certified Professional (CCP).

(a) Roles and responsibilities. A CMMC Certified Professional (CCP) completes rigorous training on CMMC and the assessment process to provide advice, consulting, and recommendations to their clients. Candidate CCPs are certified by the CAICO after successful completion of the CCP training and testing requirements set forth in paragraph (b) of this section. CCPs are eligible to become CMMC Certified Assessors and can participate as a CCP on CMMC Level 2 Certification Assessments with CCA oversight where the CCA makes all final determinations. (b) Requirements. CCPs shall: (1) Obtain and maintain certification from the CAICO in accordance with the requirements set forth in § 170.10. Certification is valid for 3 years from the date of issuance. (2) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics as set forth in § 170.8(b)(17). (3) Complete a Tier 3 background investigation resulting in a determination of national security eligibility. This Tier 3 background investigation will not result in a security clearance and is not being executed for the purpose of government employment. The Tier 3 background investigation is initiated using the Standard Form (SF) 86. These positions are designated as non-critical sensitive with a risk designation of 'Moderate Risk' in accordance with title 5 CFR 1400.201(b) and (d) and the investigative requirements of title 5 CFR 731.106(c)(2).

628. 'Cybersecurity Performance Goals,' supra note 18. Back to Citation 629. 'Proposed 45 CFR 164.308(b)(3)(i)' . Back to Citation 630. 'Proposed 45 CFR 164.308(b)(3)(ii)' . Back to Citation 631. 'Considerations for Securing Electronic Media and Devices,' Office for Civil Rights, U.S. Department of Health and Human Services, p. 1 (Aug. 2018), <https://www.hhs.gov/sites/default/files/cybersecurity-newsletter-august-2018-device-and-media-controls.pdf> . Back to Citation 632. See, e.g., Sonali Sachdeva, et al., 'Unraveling the role of cloud computing in health care system and biomedical sciences,' Heliyon (Apr. 2, 2024) ('These days numerous commercial merchants are intermingling with hospitals as well as healthcare providers to establish healthcare-based cloud computing networks.'), <https://www.ncbi-nlm-nih-gov.hhsnih.idm.oclc.org/pmc/articles/PMC11004887/> ; see also id. ([. . .] Microsoft, Google and Amazon have instantly realized that the majority of hospitals will not continue working with servers that are privately owned as well as controlled.); 'Increase in health-care cyberattacks affecting patients with cancer,' supra note 180 (In 2021, an attack against oncology services targeted data stored in cloud-based systems and affected patients in several States.). Back to Citation 633. 'See 45 CFR 164.304 (definition of 'Physical safeguards'. Back to Citation 634. 45 CFR 164.310(a)(2)(i) . Back to Citation 635. 45 CFR 164.310(b) . Back to Citation 636. 45 CFR 164.310(c) . Back to Citation 637. 'Considerations for Securing Electronic Media and Devices,' supra note 631, p. 2. Back to Citation 638. Id. Back to Citation 639. See University of Texas M.D. Anderson Cancer Center, supra note 258, p. 479. Back to Citation 640. 'Resolution Agreement,' Advocate Health Care Network Medical Group,' Office for Civil Rights, U.S. Department of Health and Human Services (July 8, 2016). Back to Citation 641. 'Resolution Agreement,' University of Rochester Medical Center,' Office for Civil Rights, U.S. Department of Health and Human Services (Oct. 30, 2019) (describing a violation of the standard for device and media controls). Back to Citation 642. 'See discussion of 45 CFR 164.306 . Back to Citation 643. See University of Texas M.D. Anderson Cancer Center, supra note 258. Back to Citation 644. 'See 45 CFR 164.304 (proposed definitions of 'Relevant electronic information systems' and 'Technology assets'. Back to Citation 645. 'See discussion of proposals to revise 45 CFR 164.316 . Back to Citation 646. 'See 45 CFR 164.304 (proposed definition of 'Implement'. Back to Citation 647. 'See proposed 45 CFR 164.308(a)(13) . Back to Citation 648. 'See 'Workstation Security: Don't Forget About Physical Security,' Office for Civil Rights, U.S. Department of Health and Human Services, p. 2 (May 2018), <https://www.hhs.gov/sites/default/files/cybersecurity-newsletter-may-2018-workstation-security.pdf> . Back to Citation 649. 'See proposed 45 CFR 164.308(a)(11)(ii)(A) (1).

Under the CMMC Program, CMMC contract requirements include self-assessments and third-party assessments for CMMC Level 2, predicated on program criticality, information sensitivity, and the severity of cyber threat. Based on the type and sensitivity of the information to be protected, a defense contractor must achieve the appropriate CMMC Status and demonstrate implementation of the associated set of information protection requirements. If the CMMC Status of Level 1 (Self) or Level 2 (Self) is a contract requirement, the defense contractor will be required to self-assess its compliance with the CMMC Level 1 or Level 2 security requirements and submit both the self-assessment results and an affirmation of conformance in SPRS. Level 1 self-assessment and associated

affirmation is required annually. Level 2 self-assessment is required every three years with an affirmation following the self-assessment and annually after the Final CMMC Status Date. If the CMMC Status of Level 2 (C3PAO) is a contract requirement, the Level 2 certification assessment must be performed by an authorized or accredited CMMC Third Party Assessment Organization (C3PAO). When the CMMC Status of Level 3 (DIBCAC) is a contract requirement, the Level 3 certification assessment by DCMA DIBCAC is required following the achievement of the CMMC Status of Final Level 2 (C3PAO). Upon achievement of the CMMC Status of Level 2 (C3PAO) or Level 3 (DIBCAC), the offeror will be issued a Certificate of CMMC Status. The assessment results are documented in SPRS to enable contracting officers to verify the CMMC Status and CMMC Status Date (i.e., not more than three years old) of an offeror prior to contract award. The offeror must also submit an affirmation of conformance in SPRS following the assessment and annually after the Final CMMC Status Date. CMMC allows the use of a Plan of Action and Milestones (POA&Ms) for specified CMMC Level 2 and Level 3 security requirements. Each POA&M must be closed (i.e., all requirements completed), within 180 days of the initial assessment. (printed page 83170) The details of the requirements for self-assessment, certification assessment, and affirmation for each CMMC Level, are provided in §§ 170.15 through 170.18. POA&M requirements and affirmation requirements are provided in §§ 170.21 and 170.22.

CIS Safeguard 4.4 · Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent. Implementation Groups: 1,2,3 Asset Type: devices Security Function: protect Parent Control: Secure Configuration of Enterprise Assets and Software

IR.L2-3.6.1 · Incident Handling CMMC Assessment Guide · Level 2 | Version 2.13 137 DISCUSSION [NIST SP 800-171 REV. 2]121 Organizations recognize that incident handling capability is dependent on the capabilities of organizational systems and the mission/business processes being supported by those systems. Organizations consider incident handling as part of the definition, design, and development of mission/business processes and systems. Incident-related information can be obtained from a variety of sources including audit monitoring, network monitoring, physical access monitoring, user and administrator reports, and reported supply chain events. Effective incident handling capability includes coordination among many organizational entities including mission/business owners, system owners, authorizing officials, human resources offices, physical and personnel security offices, legal departments, operations personnel, procurement offices, and the risk executive. As part of user response activities, incident response training is provided by organizations and is linked directly to the assigned roles and responsibilities of organizational personnel to ensure that the appropriate content and level of detail is included in such training. For example, regular users may only need to know who to call or how to recognize an incident on the system; system administrators may require additional training on how to handle or remediate incidents; and incident responders may receive more specific training on forensics, reporting, system recovery, and restoration. Incident response training includes user training in the identification/reporting of suspicious activities from external and internal sources. User response activities also includes incident response assistance which may consist of help desk support, assistance groups, and access to forensics services or consumer redress services, when required. NIST SP 800-61 provides guidance on incident handling. SP 800-86 and SP 800-101 provide guidance on integrating forensic techniques into incident response. SP 800-161 provides guidance on supply chain risk management. FURTHER DISCUSSION Incident handling capabilities prepare your organization to respond to incidents and may: · identify people inside and outside your organization you may need to contact during an incident; · establish a way to report incidents, such as an email address or a phone number; · establish a system for tracking incidents; and · determine a place and a way to store evidence of an incident. Software and hardware may be required to analyze incidents when they occur. Incident prevention activities are also part of an incident-handling capability. The incident-handling team provides input for such things as risk assessments and training. OSAs detect incidents using different indicators. Indicators may include: · alerts from sensors or antivirus software; 121 NIST SP 800-171 Rev. 2, p. 26.

Control UM-1: authentication use cases is shown in Table A.3 below. This approach is possible because of the granularity of description of each PIV Authentication Use Case in the FIPS 201-2 specification document. In this context, an observation is in order regarding the functionality provided by the primitive authentication mechanism PUM-1. PUM-1 provides the assurance that the person identifier in the smart token has been issued by the authorized card issuer and has since not

been tampered with. It accomplishes this objective by verifying the digital signature associated with a CHUID object that is dedicated for carrying this person identifier value and its associated attributes. However, the same assurance is also provided by PUM-2.1, PUM-2.2 and PUM-6 primitive authentication use cases. This is the underlying logic for including PUM-1 (and its associated verified bindings) as a constituent primitive authentication mechanism whenever the above three primitive authentication mechanisms (i.e., PUM-2.1, PUM-2.2 and PUM-6) are part of constituent primitive authentication mechanisms in any PIV authentication use case. This is the case with PIV authentication mechanisms PKI-CAK, BIO, BIO-A and PKI-AUTH and is appropriately shown in Table A.3. In PUM-2.1 and PUM-2.2, the origin and integrity of the person identifier are ensured by validating the digital certificate that includes this value. In PUM-6, the same assurance is provided by verifying the digital signature of the signed biometric object that contains the person identifier. Table A.3.

) The requested information is specified in agency regulations as being information the release of which would have an adverse effect on the ability of the Government to obtain the same or similar information in the future. (D) To qualify for withholding, the information must meet the following limitations: (1) If the information came into the possession or under the control of the U.S. Government prior to October 30, 2000, and more than 25 years prior to receipt of the FOIA request, the DoD Component shall notify the foreign government or international organization of the request for disclosure. The information then qualifies for withholding only if the foreign government or international organization requests in writing that the information not be disclosed for a specific period of time. This date can be extended with a later request by the foreign government or international organization. (2) If the information came into the possession or under the control of the U.S. Government after October 30, 2000, the information cannot be withheld after the release date specified by the foreign government or international organization. In the case where one or more foreign governments or international organizations provided the information, the latest date specified by any of them will be used. If no release date was specified, and the information came into the possession of the DoD Component more than 10 years prior to receipt of the FOIA request, the procedures set forth in § 286.18(d)(1)(i) apply. § 286.19 Initial determinations. (a) IDA. (1) The determination whether to withhold information responsive to a FOIA request shall be made by any suitable official designated in writing as an IDA by the DoD Component. In designating IDAs, the DoD Component shall balance the goals of centralization of authority to promote uniform decisions, and decentralization to facilitate responding to each request within the time limitations of the FOIA. The IDA shall review all withheld information to determine whether it meets the criteria for withholding under one or more of the FOIA exemptions. This determination may be made upon the recommendation of a review official. (2) IDAs and review officials shall not use the existence of classification markings, distribution limiting statements, such as ·For Official Use Only· markings, as justification to withhold information. Information so marked must be reviewed after the receipt of a FOIA request to determine if the markings still apply. (3) To deny, in whole or in part, a requested record that is in the possession and control of the DoD Component, the IDA must determine that one or more of the FOIA exemptions justify withholding all or part of the record.

Some comments received lacked relevance to the rule's content, which is limited to specific CMMC Program requirements. The DoD declines to address speculation about lobbying activities. Verifying compliance with applicable security requirements may increase financial cost to the DoD due to increased contract costs but it is necessary for the protection of DoD CUI. The cost of lost technological advantage over potential adversaries is greater than the costs of such enforcement. The value of information (and impact of its loss) does not diminish when the information moves to contractors. The trade-off is between protecting sensitive information from our nation's adversaries and accepting the fact that security costs increase for numerous reasons. Many of those cost-drivers are completely independent of CMMC. While CMMC compliance adds to an organization's cost, no member of the DIB can assume the status-quo in today's ever-changing cyber security environment. Increasing costs to protect the nation's data and industries from (printed page 83151) emerging threats is simply a component of doing business anywhere in the world. Processing, storing, or transmitting sensitive Government information comes with a handling cost that needs to be built into each organization's business model. Some comments included suggestions about how workflow should occur between prime and subcontractors to decrease or eliminate the transfer of CUI to subcontractors. The DoD cannot dictate these business practices but encourages prime contractors to work with its subcontractors to flow down CUI with the required security and the least burden.

Questions regarding what to mark as CUI are out of scope of this rule. At the time of award, the DoD may have no visibility into whether the awardee will choose to further disseminate DoD's CUI, but DFARS clause 252.204-7012 and DFARS clause 252.204-7021 require that the prime contractor to flow down the information security requirement to any subcontractor with which the CUI will be shared. Decisions regarding which DoD information must be shared to support completion of which subcontractor tasks takes place between the prime contractor and the subcontractors chosen to complete the specific tasks. c. Phasing the Cost To Comply Comment: Two comments suggested a phased compliance would help offset financial burden while working toward full compliance. One comment expressed concern that Managed Service Providers (MSPs), many of which are small businesses, will not have time to achieve Level 2 certification before their OSA and OSC customers need them to be certified and recommended extending the phased timeline.

However, an organization that receives a product from a custom development team and/or a commercial off-the-shelf (COTS) supplier can register the contained (trusted) software files, and - Identify software files through the use of trusted digital fingerprint repositories; - Link products to software files through a SWID tag; - Whitelist authorized software and block all other software by default; - Blacklist (and block by default) unauthorized and/or known malicious or unsafe software; - Graylist (and block by default or allow by exception) until a determination is made of whether to authorize particular software; - Require installation media to be digitally signed by a trusted source early in the supply chain to prevent tampering in the supply chain. Installation media can also include a signed SWID tag; - Require all mobile code to be digitally signed by a trusted source; and - Use a trusted platform module to verify the software used to boot the system.

728. Id. Back to Citation 729. · See discussion of 45 CFR 164.312 , *infra*. Back to Citation 730. ·Letter from NCVHS Chair Jacki Monson (2023), *supra* note 123, Appendix p. 2. Back to Citation 731. ·The Department is also proposing to delete the implementation specification for encryption at 45 CFR 164.312(e)(2)(ii) because we are proposing to address the substantive requirements of that implementation specification in proposed 45 CFR 164.312(b)(2) . Back to Citation 732. ·Cybersecurity Performance Goals,· *supra* note 18; Letter from NCVHS Chair Jacki Monson (2023), *supra* note 123, Appendix p. 2. Back to Citation 733. · See 45 CFR 170.315(d)(7) and 170.210(a) . Back to Citation 734. ·For example, adoption of health IT that is certified through the ONC Health IT Certification Program as having the technical capability to encrypt, or prevent the local storage of, electronic health information stored on end-user devices after use of the technology on those devices stops may contribute to a regulated entity's compliance with the proposed implementation specification for encryption and decryption. See 45 CFR 170.315(d)(7) . Additionally, the proposed implementation specification generally is consistent with the Health Data, Technology, and Interoperability: Patient Engagement, Information Sharing, and Public Health Interoperability (HTI-2) NPRM proposal to modify 45 CFR 170.315(d)(7) , should it be finalized, to include requirements that authentication credentials be protected using industry-standard encryption and decryption. See 89 FR 63536-37 , 63778 (Aug. 5, 2024). Back to Citation 735. ·Messaging in the context of telehealth is discussed in Department guidance on telehealth. See ·Guidance on How the HIPAA Rules Permit Covered Health Care Providers and Health Plans to Use Remote Communication Technologies for Audio-Only Telehealth,· Office for Civil Rights, U.S. Department of Health and Human Services (June 13, 2022), <https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/hipaa-audio-telehealth/index.html> . Back to Citation 736. ·For example, health IT certified through the ONC Health IT Certification Program as meeting the ·[v]iew, download, and transmit to 3rd party· certification criterion must be able to create and transmit continuity of care document summaries to patients through email via an encrypted method of electronic transmission. See 45 CFR 170.315(e)(1) . Back to Citation 737. ·The ONC Health IT Certification Program sets forth at 45 CFR 170.550(h)

gs and relationships between the security standards and guidelines developed by NIST, the International Organization for Standardization (ISO), and the International Electrotechnical Commission (IEC). Identify determination statements for organization-defined parameters (ODPs) first and separately from the determination statements for each control item; Improve the readability of the assessment procedures; Provide a structured schema for automated tools when assessment information is imported into such tools; Provide greater flexibility in conducting assessments by giving organizations the capability to target certain aspects of controls (highlighting the particular weaknesses and/or deficiencies in controls), Improve the efficiency of security and privacy control assessments; Support continuous monitoring and ongoing authorization programs by

providing a greater number of component parts of security and privacy controls that can be assessed at organization-defined frequencies and degrees of rigor.

) (§ 20.84), its contractors (§ 20.90), other Federal government agencies (§ 20.85), or foreign government agencies (§ 20.89). Procedural and other safeguards must be followed for FDA to share nonpublic information with other persons. For FDA to share confidential commercial information with CBP under § 20.85, CBP must sign a written agreement that it will not further disclose the information except with FDA's written permission. (Comment 158) Several comments express concern about the risk of disclosure of information about a formula or recipe. One of these comments noted that, even if the complete formula may not be disclosed, listing the source of each ingredient in a product would reveal the recipe for that product. Other comments ask how FDA would handle commercially sensitive information that might be derived if FDA provides information about a one-up source nontransporter for each of the ingredients in a recipe. (Response) As discussed in response to comment 74 of this document, several statutes and the agency's information disclosure regulations at parts 20 and 21 govern the agency's ability to disclose information to the public, including information obtained under section 306 of the Bioterrorism Act. For example, section 301 of the FD&C Act prohibits any person from using *** to his own advantage, or revealing, other than to the Secretary or officers or employees of the Department, or to the courts ***, any information acquired under authority of [section 414 or 704] concerning any method or process which as a trade secret is entitled to protection ***. FDA follows these laws in determining the proper treatment of the information it receives. N. Comments on What Are the Consequences of Failing to Establish and Maintain Records or Make Them Available to FDA as Required by This Subpart? (Proposed § 1.363) (Comment 159) Three comments state that imposition of criminal liability would be inappropriate and excessive if they performed to the best of their abilities. The comments state that taking time beyond 4 hours to locate, compile, and provide records on a detained article's manufacture should not be viewed as a prohibited act. (Response) As noted previously, FDA has changed the proposed times in § 1.361 of this final rule for responding to a request for access to records to a requirement that all records be made available as soon as possible, not to exceed 24 hours from the time of receipt of the official request. Failure to establish or maintain records or refusal to permit access to or verification or copying of any record is a prohibited act under section 301 of the FD&C Act.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 201, 245, and 252 RIN Number 0750-AG38 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) regarding Government Property, to reflect the recent revisions to Government Property elsewhere in the Code of Federal Regulations. DATES: Effective Date: August 19, 2011. FOR FURTHER INFORMATION CONTACT: Ms. Meredith Murphy, 703-602-1302. SUPPLEMENTARY INFORMATION: I. Background DoD is revising subparts 245.6 and 245.7 to be consistent with the changes to FAR subparts 45.6 and 45.7, published in the Federal Register at 72 FR 27364 on May 15, 2007. A proposed DFARS rule was published in the Federal Register at 75 FR 75444 on December 3, 2010. The public comment period for the proposed rule closed February 1, 2011. Comments were received from three respondents. A discussion and analysis of the comments is provided in section II of this notice. Any revisions to the final rule based on public comments are addressed in the DoD responses to the comments received. II. Discussion and Analysis Comments received in response to the proposed rule are organized into six categories and are discussed in the paragraphs that follow. A. Clarifying Responsibilities Comment: A respondent recommended that * * * or the head of the contract administration office be added to DFARS 201.670(a). DoD response: DFARS 201.670(a) has been revised to specify that the appropriate agency authority may delegate contract administration functions to the cognizant contract administration office, in which case the contract administration office appoints the property administrators and plant clearance officers in writing. This language was formerly found at DFARS 245.70. Comment: A respondent recommended that DFARS 252.245-70XX(i) be revised to make the contractor's responsibility for compliance with export control law and regulations a due diligence responsibility. DoD Response:

the check system specific result file and check name within the result file using the @href and @name attributes, respectively. This approach provides traceability between XCCDF and check results. 9. Where applicable to the target system, each of the following <xccdf:fact> elements SHALL be provided:

Apply and document appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity or business associate in accordance with the written policies and procedures for sanctioning workforce members required by paragraph (a)(6)(ii)(A) of this section. (7) Standard: Information system activity review ·(i) General. Implement written policies and procedures for regularly reviewing records of activity in the covered entity's or business associate's relevant electronic information systems. (ii) Implementation specifications ·(A) Policies and procedures. Establish written policies and procedures for retaining and reviewing records of activity in the covered entity's or business associate's relevant electronic information systems by persons and technology assets, including the frequency for reviewing such records. (B) Scope. Records of activity in the covered entity's or business associate's relevant electronic information systems by persons and/or technology assets include but are not limited to audit trails, event logs, firewall logs, system logs, data backup logs, access reports, anti-malware logs, and security incident tracking reports. (C) Record review. Review records of activity in a covered entity's or business associate's relevant electronic information systems by persons and technology assets as often as reasonable and appropriate for the type of report or log and document such review. (D) Record retention. Retain records of activity in the covered entity's or business associate's relevant electronic information systems by persons and technology assets for a period of time that is reasonable and appropriate for the type of report or log. (E) Response. Where a suspected or known security incident is identified during the review required by paragraph (a)(7)(ii)(C) of this section, respond in accordance with the covered entity's or business associate's security incident response plan required by paragraph (a)(12)(ii)(A)(1) of this section. (F) Maintenance. Review and test the written policies and procedures required by paragraph (a)(7)(ii)(A) of this section at least once every 12 months and modify as reasonable and appropriate. (8) Standard: Assigned security responsibility. In writing, identify the security official who is responsible for the development and implementation of the policies and procedures, written or otherwise, and deployment of technical controls required by this subpart for the covered entity or business associate. (9) Standard: Workforce security ·(i) General. Implement written policies and procedures to ensure that all members of its workforce have appropriate access to electronic protected health information and relevant electronic information systems, and to prevent those workforce members who are not authorized to have access from obtaining access to electronic protected health information and relevant electronic information systems. (ii) Implementation specifications ·(A)

(Comment 142) Some comments state that the proposed time is reasonable for record production if the requested records are onsite and of recent transactions (i.e., within the last 3 months). One comment urges the agency to clarify that, although companies must make the records available within 4 hours, the agency does not expect companies to link the sources of each ingredient with every finished lot of product within that timeframe. Another comment states that, within the 4-hour proposed time, a firm will not be able to make records available that are stored offsite and currently are subject to contracts that allow the vendors to deliver records on the next business day. The comment recommends that FDA consider the possibility of allowing records stored offsite to be produced at locations more convenient than the manufacturing facility, such as FDA offices, headquarters, or other locations mutually agreed upon to expedite record examination. Some comments also state that the cost of renegotiating record storage contracts would cost thousands of dollars, more than the \$151 per firm cost that FDA estimated. They recommend that FDA allow companies to provide records ·within a reasonable period of time· or that the final rule (printed page 71606) give companies 24 hours to make records available to FDA from the time of receipt of FDA's official request. Several comments state that the proposed time does not reasonably reflect the following: The scope of requested records; the accessibility, degree of compatibility and number of recordkeeping systems involved; the limitations on record maintenance of some systems; the limited physical access to nonelectronic records; and the presence or absence of a quality assurance system. Comments further state that, with millions of foods transported annually, many firms utilize various data systems and have implemented records maintenance procedures to meet their specific company needs. Compliance with this new rule requires establishing new protocols and developing new database systems, which would require a substantial capital investment.

In calendar year (CY) 2021 DoD paused the planned CMMC rollout to conduct an internal review of the CMMC Program. The internal review resulted in a refined and streamlined set of requirements that addressed many of the concerns identified in the public comments received relating to CMMC 1.0. These changes have been incorporated into the CMMC Program structure and policies, now referred to as CMMC 2.0. In July 2022, the CMMC PMO met with the Office of Advocacy for the United States Small Business Administration (SBA) to address the revisions planned in CMMC 2.0 that are responsive to prior SBA concerns. The CMMC Program will enhance the ability of the DoD to safely share sensitive unclassified information with (printed page 89081) defense contractors and know the information will be suitably safeguarded. Once fully implemented, CMMC will incorporate a set of cybersecurity requirements into acquisition contracts to provide verification that applicable cyber protections have been implemented. Under the CMMC Program, defense contractors and subcontractors will be required to implement certain cybersecurity protection requirements tied to a designated CMMC level and either perform a self-assessment or obtain an independent assessment from either a third-party or DoD as a condition of a DoD contract award. CMMC is designed to validate the protection of sensitive unclassified information that is shared with and generated by the Department's contractors and subcontractors. Through protection of information by adherence to the requirements verified in CMMC 2.0, the Department and its contractors will prevent disruption in service and the loss of intellectual property and assets, and thwart access to sensitive unclassified information by the nation's adversaries. The CMMC Program is intended to: (1) align cybersecurity requirements to the sensitivity of unclassified information to be protected, and (2) add a certification element, where appropriate, to verify implementation of cybersecurity requirements. As part of the program, DoD also intends to provide supporting resources and training to defense contractors to help support companies who are working to achieve the required CMMC level. The CMMC Program provides for assessment at three levels: basic safeguarding of FCI at CMMC Level 1, broad protection of CUI at CMMC Level 2, and enhanced protection of CUI against risk from Advanced Persistent Threats (APTs) at CMMC Level 3. The CMMC Program is designed to provide increased assurance to the Department that a defense contractor can adequately protect sensitive unclassified information (i.e., FCI and CUI) in accordance with prescribed security requirements, accounting for information flow down to its subcontractors in a multi-tier supply chain.

In addition, FDA should acknowledge the unique, closed distribution model of the direct selling business and exempt independent distributors in a direct selling organization from the requirement to maintain records concerning the immediate previous source. In the closed distribution model of direct selling, the direct selling company is the source of all products sold by its distributors. Distributors typically obtain the products they redistribute directly from the direct selling company with which they are associated. Under the proposed regulations, the direct selling company will maintain records that identify the carriers and the distributors who are the immediate subsequent recipients of the product. Any records maintained by the distributor regarding the immediate previous source for such shipments would be wholly duplicative of the records held by the direct selling company. (Response) Whether these independent distributors are subject to the requirement to establish and maintain records to identify the immediate subsequent recipients depends on the nature of their customers. Section 1.327(d) of this final rule excludes persons who distribute food directly to consumers from the requirement in § 1.345 of this final rule to establish and maintain records of the nontransporter and transporter immediate subsequent recipients. As discussed in response to comment 37, FDA concluded that to require such records would be too burdensome and not necessary to help address credible threats of serious adverse health consequences or death to humans or animals. Thus, independent distributors are not required to maintain records of subsequent recipients who are consumers. Independent distributors, however, are required to keep records of subsequent recipients who are not consumers. However, an independent distributor who qualifies as a retail food establishment under § 1.327(e) of the final rule that also distributes food to persons who are not consumers is required to identify the nontransporter and transporter immediate subsequent recipients as to those transactions only to the extent the information is reasonably available. FDA needs such records to quickly and effectively traceback and trace forward in the event of a food-related emergency. However, an independent distributor who qualifies as a retail food establishment that employs 10 or fewer full-time equivalent employees is excluded from all of the requirements in this subpart, except the record access provisions for existing records under §§ 1.361 and 1.363.

According to FedRAMP data and subject matter experts, there are approximately 280 unique FedRAMP-

authorized and ready cloud service offerings available to the Federal Government. For this estimate, the Government will award approximately 280 contracts for cloud services impacted by this rule over a five-year period (20 percent each year). Based on the number of FedRAMP-authorized offerings, the Government estimates that there are approximately 56 new or revised FIS offerings (20 percent * 280 cloud service offerings) each year for which the Government contracts. For this estimate, the Government assumes: the number of new or revised FIS offerings the Government contracts for each year is equivalent to the number new FIS impacted by this rule annually; one service provider is responsible for executing all the requirements of this rule for a FIS; and that each FIS is being serviced by a different contractor. Therefore, the Government estimates that 56 unique entities will be awarded a contract annually for the development, implementation, operation, or maintenance of a cloud FIS on behalf of the Government. Based on the input of subject matter experts, the Government further estimates that: Of the 28 contractors that will be awarded a contract each year to operate or maintain a non-cloud FIS, approximately three (10 percent) are small businesses and 25 (90 percent) are other than small businesses. Of the 56 contractors that will be awarded a contract each year to operate or maintain a cloud FIS, approximately three (five percent) are small businesses and 53 (95 percent) are other than small businesses.

B. Contractor Compliance Requirements and Estimate of Cost The total estimated annualized public costs associated with this FAR rule over a ten-year period (calculated at a 7-percent discount rate) are approximately \$55 million annually, or \$388 million in net present value, based on the discussion in paragraphs IV.B.1. through IV.B.7 below. The following compliance requirements in FAR clause 52.239-YY and 52.239-XX are considered new to the FAR for all Federal contractors that develop, implement, operate, or maintain a FIS using cloud or non-cloud computing services, as applicable:

1. Regulatory Familiarization The new FAR clauses are prescribed for use in solicitations and contracts for services to develop, implement, operate, or maintain a FIS. It is expected that all 84 contractors (28 non-cloud FIS contractors + 56 cloud FIS contractors) awarded a contract annually for these services will need, to some degree, to become familiar with the various compliance requirements of the FAR, as well as the requisite and applicable NIST SP guidelines, FIPS Publication standards, CISA BODs and EDs, and FedRAMP requirements, to be prepared to implement and maintain the cybersecurity standards and requirements for a FIS in performance of a Federal contract. It is assumed that most contractors will be familiar with, to some degree, some or all these documents.

Program makes no change to the CUI program or its implementing policies. Contractually, DFARS clause 252.204-7012, effective since December 2017, requires contractors to implement the NIST SP 800-171 security requirements to provide adequate security applicable for processing, storing, or transmitting CUI in support of the performance of a DoD contract. That requirement applies, regardless of the number of computers or components in a non-Federal information system. The CMMC Program provides an assessment mechanism to verify that prospective offerors comply with the applicable information security requirements. All executive agencies are required to follow the policies described in 32 CFR 2002.14. DoD aligned CMMC requirements with NIST SP 800-171 R2 because it is enterprise focused and is already required in DoD contracts when DFARS clause 252.204-7012 is applicable. DFARS clause 252.204-7012 and NIST SP 800-171 R2 provide the cybersecurity requirements, whereas CMMC validates implementation of those requirements. CMMC does not duplicate these documents. The DoD publishes Security Technical Implementation Guides (STIGs) for specific products, primarily to guide secure implementation in DoD systems. The OSA is responsible for creating the implementation guidance they will use to meet the CMMC security requirements. OSAs are free to use the DoD STIGs if they feel they are appropriate. The DoD does not want to limit the choices available to the OSA for implementation guidance. In addition, the DoD declines to create STIGs for all products that might be used in the OSA's environment. Some comments lacked relevance to the rule's content, which is limited to specific CMMC program requirements. Changes to DFARS clause 252.204-7012 are outside the scope of this rule. DoD declines to modify CMMC Level 2 or Level 3 requirements related to use of Cloud Service Providers (CSP). A CSP is assessed against the FedRAMP Moderate baseline. This is required when a CSP, regardless of the component or type of CSP, processes, stores, or transmits CUI. The DoD declines to align CMMC requirements to alternate standards or accept compliance with alternate standards in lieu of the NIST SP 800-171 standard mandated by 32 CFR part 2002 for the protection of CUI. CMMI is focused on improving the software development process, while CMMC is focused on verifying the proper implementation of DIB cybersecurity requirements. Incorporating requirements into new or other existing standards would unacceptably delay action to improve DIB cybersecurity. The DoD must take action to improve DIB cybersecurity, regardless of the global state of cybersecurity. DoD's publication of this rule

follows completion of OMB's formal rulemaking process, which includes both DoD internal coordination and Interagency coordination. The recommendation for the DoD to establish a voluntary DIB Cyber Protection Program is beyond the scope of this rule.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analysis to advance the development and productive use of information technology. ITL's responsibilities include the development of technical, physical, administrative, and management standards and guidelines for the cost-effective security and privacy of sensitive unclassified information in Federal computer systems. This Interagency Report discusses ITL's research, guidance, and outreach efforts in computer security, and its collaborative activities with industry, government, and academic organizations. This report received the support of many individuals. The author is grateful to Tim Grance for suggesting the topic and encouraging its development. The author also wishes to thank colleagues who reviewed drafts of this document and contributed to its technical content, as well as the individuals who reviewed the public-release draft of this document and provided comments during the review period. Improvements to the content would not have been possible without their feedback and valuable suggestions. In particular, Paul Black, Lee Badger, and Russell Cameron Thomas offered useful and thought-provoking insight on the subject matter. However, the author takes full responsibility for any remaining errors or omissions in the report. - GLYPH<c=31;font=/AGOCAF+Webdings> Strategic support - Assessments of security properties can be used to aid different kinds of decision making, such as program planning, resource allocation, and product and service selection.

- 5]. 6. An attacker can obtain sensitive data by evaluating and probing shared microarchitectural resources in contexts that should be isolated (e.g., caches and branch prediction logic) [CWE-1303].
7. Malicious software can take advantage of incorrectly assigned default permissions to obtain unauthorized access [CWE-276].

CMMC flow down requirements are designed to apply consistent assessment requirements to all contractors, whether prime or subcontractor and regardless of company size, who are required to adequately safeguard CUI. The DoD cannot dictate DIB business practices and encourages prime contractors to carefully consider the necessity of sharing CUI information and to work with its subcontractors to flow down CUI with the required security and the least burden. Defense contractors may share information about their CMMC Status with other DIB members to facilitate effective teaming arrangements when competing for DoD contract opportunities. In addition, CMMC requirements apply for prime contractors and their subcontractors as outlined in § 170.23. For additional information about flow down of contractual requirements, see the 48 CFR part 204 CMMC Acquisition rule, RIN 0750-AK81, Assessing Contractor Implementation of Cybersecurity Requirements (DFARS Case 2019-D041). (printed page 83202) 12. International. Commenters expressed concern about international partners' use of cloud services that do not have FedRAMP or GovCloud equivalency. Also concerns that the draft language [in the proposed rule] did not explain reciprocity of cybersecurity standards between the U.S. and International Partners. One commenter recommended exempting foreign businesses from assessment requirements. DoD Response: A domestic or international business seeking a contract that includes DFARS clause 252.204-7012, and using a cloud service provider to process, store, or transmit covered defense information in performance of that DoD contract, must meet FedRAMP authorization or equivalency requirements. As the FedRAMP program and FedRAMP equivalency are available to international organizations, foreign partners do not need to develop their own FedRAMP program. The DoD leverages FedRAMP to provide the requirements for the adoption of secure cloud services across the Federal Government by providing a standardized approach to security and risk assessment for cloud technologies and Federal agencies. The Implementation of CMMC Program requirements described in § 170.3(e) of the rule does not promote assessments of any contractors over any other contractors. All companies, regardless of size, location, or nationality, will have access to authorized C3PAOs for certification assessments. The rule does not preclude non-U.S. citizens or foreign-owned C3PAOs from operating in the U.S. Additionally, U.S.-owned C3PAOs may operate in a foreign nation. Section 170.20 states that OSCs that have completed a DCMA DIBCAC High Assessment aligned with CMMC Level 2 Scoping will be given the CMMC Status of Final Level 2 (C3PAO). International standards acceptance is not addressed in this rule. Any consideration of reciprocity between foreign partner protected information and CUI and FCI would require a formal government to government international arrangement or agreement and is outside the scope of this 32

a new requirement. DCMA is leading an effort to revise and update the sales terms and conditions found today at 245.7309. Once completed, and in coordination with the Services, the sales terms and conditions will be incorporated into the DFARS. It should be noted that sales terms and conditions specific to demilitarization, mutilation, and destruction will remain within the clause at 252.245-7004 due to the general sensitivity of demilitarization, mutilation, and destruction actions.

D. Demilitarization, Mutilation, and Destruction Comment: A respondent recommended that 252.245-70XX(e)(8) be deleted in its entirety and that special conditions be placed into the PGI, including that the agency must provide direction and funding. DoD Response: It is incumbent upon the Government to provide the contractor, as part of contract terms and conditions, any demilitarization, mutilation, or destruction requirements (reference DoD 5000.2-R, paragraph C2.8.7., Demilitarization and Disposal Planning). No additional clarification is necessary.

Comment: A respondent requested confirmation that the requirement to validate disposal of contractor inventory in foreign countries at paragraph (d) of the clause at 252.245-70XX is a Government responsibility. The respondent also asked if validation takes place when the plant clearance officer reviews and accepts the bid and whether DCMA International should get involved. The respondent recommended indicating who has the responsibility, specifying that State Department approval is required, and adding a certification statement to the SF 1428 providing the validation to the contractor. DoD Response: The language at DFARS 252.245-70XX(d) pertaining to disposal of contractor inventory overseas has been removed from the final rule. DFARS 252.245-7004, paragraph (g), has been clarified to ensure that disposal of contractor inventory located overseas is governed by contract terms and conditions. Additionally, the DoD responsibilities contained in the PGI sufficiently address this issue. Comment: A respondent expressed concern that the language at DFARS 252.245-70XX could be interpreted as requiring the contractor to determine the appropriate level of demilitarization required; the respondent suggested clarifying the intent. DoD Response: It is incumbent upon the Government to provide the contractor with, as part of contract terms and conditions, any demilitarization, mutilation, or destruction requirements (reference DoD 5000.2-R, paragraph C2.8.7., Demilitarization and Disposal Planning). No additional clarification is needed.

E. Scrap Procedures Comment: A respondent recommended deleting DFARS 252.245-70XX(j)(1), Contractor with an approved scrap procedure, in its entirety because the scrap procedures are typically incorporated within the contractor's property management system. DoD Response:

(3) Unmarked or mismarked CUI is not considered a CUI incident unless the mismarking or lack of marking has resulted in the mishandling or improper dissemination of the information. The contracting officer shall consult with the appropriate agency personnel concerning any unmarked or mismarked CUI in accordance with agency procedures. 4.403-7 Solicitation provision and contract clauses. (a) Insert the provision at 52.204-WW, Notice of Controlled Unclassified Information Requirements, in solicitations that contain the clause at 52.204-XX or the clause at 52.204-YY. (b) Except for solicitations and contracts solely for the acquisition of COTS items, insert the clause at 52.204-XX, Controlled Unclassified Information, and include an SF XXX Controlled Unclassified Information (CUI) Requirements, in solicitations and contracts if the requiring activity has marked the 'Yes' box in Part A of the SF XXX. (c) Insert the clause at 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information, in solicitations and contracts if the requiring activity has marked the 'No' box in Part A of SF XXX, excluding solicitations and contracts solely for the acquisition of COTS items. 12. Revise section 4.404 and add sections 4.404-1 through 4.404-3 to read as follows: 4.404 Basic Safeguarding of Covered Contractor Information Systems. 4.404-1 Definitions. As used in section 4.404- Covered contractor information system means an information system owned or operated by a contractor on which the contractor processes, stores, or transmits covered Federal information. Covered Federal information means information provided by or created for the Government, when that information is other than- (1) Simple transactional information (such as that necessary to process payments); (2) Information already publicly released (such as on public websites), or marked for public release, by the Government; (3) Federally-funded basic and applied research in science, technology, and engineering at colleges, universities, and laboratories in accordance with National Security Decision Directive 189; (4) Controlled unclassified information (CUI); or (5) Classified information. 4.404-2 Applicability. (a) This section applies to all acquisitions, including acquisitions of commercial services or commercial products other than commercially available off-the-shelf (COTS) items, when a contractor's information system may contain covered Federal information as part of performance on the contract. (b) While covered Federal information is not

required to be marked or identified by the Government, some (printed page 4294) administrative markings (e.g., draft, deliberative process, predecisional, not for public release) can indicate that the information is covered Federal information. 4.404-3 Contract clause.

From the NIST SP 800-172 Rev 3 Final Public Draft: The continued need for an internal system connection is reviewed from the perspective of whether it provides support for organizational missions or NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 business functions. This requirement is sourced to a control tailored out of the SP 1742

the invasion of the privacy of individuals only incidentally related to an investigation. The exemption of the individual's right of access to portions of these records, and the reasons therefore, necessitate the exemption of this system of records from the requirement of the other cited provisions. (B) [Reserved] (iv) Exemptions. (A) Information specifically authorized to be classified under E.O. 12958 , as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Records maintained in connection with providing protective services to the President and other individuals under 18 U.S.C. 3506 , may be exempt pursuant to 5 U.S.C. 552a(k)(3) . (C) Records maintained solely for statistical research or program evaluation purposes and which are not used to make decisions on the rights, benefits, or entitlement of an individual except for census records which may be disclosed under 13 U.S.C. 8 , may be exempt pursuant to 5 U.S.C. 552a(k)(4) . (D) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (E) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6) , if the disclosure would compromise the objectivity or fairness of the test or examination process. (F) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3), (d), (e)(1), (e)(4)(G) through (I), and (f). (v) Authority. 5 U.S.C. 552a(k)(1) , (k)(3), (k)(4), (k)(5) and (k)(6). (vi) Reasons. (A) The release of disclosure accountings would permit the subject of an investigation to obtain valuable information concerning the nature of that investigation, and the information contained, or the identity of witnesses or informants, would therefore present a serious impediment to law enforcement. In addition, disclosure of the accounting would amount to notice to the individual of the existence of a record. (B) Access to the records contained in this system would inform the subject of the existence of material compiled for law enforcement purposes, the premature release of which could prevent the successful completion of investigation, and lead to the improper influencing of witnesses, the destruction of records, or the fabrication of testimony. Exempt portions of this system also contain information that has been properly classified under E.O. 12958 , and that is required to be kept secret in the interest of national defense or foreign policy.

The rule also defines ·security incident· as the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations in an information system. The existing definition does not make clear that a security incident may result from two types of behaviors: those related to attempted or successful but unauthorized access, use, disclosure, modification, or destruction of information in an information system, and those that are related to the attempted or successful unauthorized interference with system operations in an information system. In other words, a security incident may directly touch upon information in a system or interfere with the operations of the system itself. The Department believes that it is necessary to clearly convey the distinct types of incidents to regulated entities to ensure that regulated entities implement and deploy safeguards that address both concerns. b. Proposal The Department proposes to modify the definition of ·security or security measures· to clarify that security or security measures may not only exist in information systems but may also be applied to information systems. [386] This clarification would better reflect the multi-layered approach to cybersecurity recommended by experts to address the concerns facing regulated entities today. For example, a regulated entity may determine that it is necessary to apply access controls and encryption mechanisms through an external mechanism, such as added firewall technology, [387] that is applied to the system, rather than technical controls that are embedded within the system or components of the system. The Department believes that the proposed definition would provide a more complete instruction. The Department proposes to reorganize the definition of ·security incident·

into two numbered paragraphs to delineate the two separate categories of security incidents. We also propose to clarify that in both instances, the definition applies when the described action affects an information system and regardless of whether an attempt to affect the information in the system or interfere with system operations is successful or not. 16. Adding Definitions of Technical Controls

a. Issues To Address Throughout the technical safeguards provisions in 45 CFR 164.312, the Department directs regulated entities to implement technical policies and procedures. The court in *M.D. Anderson* interpreted technical policies and procedures as written policies and procedures on technical matters. [388] This interpretation does not reflect the Department's intent for technical safeguards to include policies and procedures that rely on technology or technological solutions for implementation. [389] We believe that the court's interpretation could have significant consequences for the confidentiality, integrity, and availability of ePHI.

b. Proposal

The Security Rule, in conjunction with the Privacy and Breach Notification Rules, protects the privacy and security of individuals' PHI, that is, individually identifiable health information (IIHI). The Security Rule's protections are limited to ePHI, while the Privacy and Breach Notification Rules protect both electronic and non-electronic PHI. The Security Rule establishes standards to protect individuals' ePHI and requires reasonable and appropriate administrative, physical, and technical safeguards. The Security Rule specifies a series of administrative, physical, and technical security requirements that must be performed or implemented for regulated entities to safeguard ePHI. Specifically, entities regulated by the Security Rule must: (1) ensure the confidentiality, integrity, and availability of all ePHI they create, receive, maintain, or transmit; (2) protect against reasonably anticipated threats to the security and integrity of the information; (3) protect against reasonably anticipated impermissible uses or disclosures; and (4) ensure compliance by their workforce. A major goal of the Security Rule is protecting the security of individuals' health information while allowing for the development of a health information system to improve the efficiency and effectiveness of the health care system. The Administrative Simplification provisions of HIPAA (title II) provide the Secretary of HHS with the authority to publish standards for the privacy and security of health information. The Department first proposed standards for the security of ePHI on August 12, 1998, and published a final rule on February 20, 2003. The Department modified the Security Rule in 2013. Recently, as the preamble to this NPRM discusses, changes in the health care environment and insufficient compliance by regulated entities with the existing Security Rule require the modifications proposed here. For purposes of this Regulatory Impact Analysis (RIA), the proposed rule adopts the list of covered entities (with an updated count) and certain cost assumptions identified in the Department's Information Collection Request (ICR) associated with the HIPAA Privacy Rule to Support Reproductive Health Care Privacy (2024 ICR). [940] The Department also relies on certain estimates and assumptions from the 1998 Proposed Rule [941] that remain relevant, the 2003 Final Rule, [942] and the 2013 Omnibus Rule, [943] as referenced in the analysis that follows.

Because of its nature, the use of connection-separation destroys any assurance of continuity of connection (one aspect of the maintenance of service security service) that might be provided by any lower level protocol (such a service can be provided at the transport layer). When connection-separation is used above the transport layer it also effectively prevents access to the frozen references function that could otherwise be made available. The latter point would be a greater disadvantage if it were not for the likelihood of such code requiring verification for other purposes (such as maintenance of data integrity).

- The measures taken to protect data from accidental, unauthorized, intentional, or malicious modification, destruction, or disclosure. - A condition that results from the establishment and maintenance of protective measures.

(k) NIST SP 800-172, titled "Enhanced Security Requirements for Controlled Unclassified Information" provides federal agencies with recommended enhanced security requirements for protecting the confidentiality of CUI: (1) when the information is resident in nonfederal systems and organizations; (2) when the nonfederal organization is not collecting or maintaining information on behalf of a federal agency or using or operating a system on behalf of an agency; and (3) where there are no specific safeguarding requirements for protecting the confidentiality of CUI prescribed by the authorizing law, regulation, or government-wide policy for the CUI category listed in the CUI Registry. The enhanced requirements apply only to components of nonfederal systems that process, store, or transmit CUI or that provide security protection for such components when the designated CUI is associated with a critical program or high value asset. The enhanced requirements supplement

the basic and derived security requirements in NIST SP 800-171 and are intended for use by federal agencies in contractual vehicles or other agreements established between those agencies and nonfederal organizations. This document is incorporated by reference as a foundational source for security requirements. (l) NIST SP 800-172A, titled "Assessing Enhanced Security Requirements for Controlled Unclassified Information" provides federal agencies and nonfederal organizations with assessment procedures that can be used to carry out assessments of the requirements in NIST SP 800-172. The assessment procedures are flexible and can be tailored to the needs of organizations and assessors. Assessments can be conducted as (1) self-assessments; (2) independent, third-party assessments; or (3) government-sponsored assessments. The assessments can be conducted with varying degrees of rigor based on customer-defined depth and coverage attributes. The findings and evidence produced during the assessments can be used to facilitate risk-based decisions by organizations related to the CUI enhanced security requirements. This document is incorporated by reference as a foundational source for definitions and assessment. (m) Committee on National Security Systems (CNSS) Instruction No. 4009 provides a glossary of terms and applies to all U.S. Government Departments, Agencies, Bureaus and Offices, supporting contractors and agents that collect, generate, process, store, display, (printed page 89063) transmit or receive classified or controlled unclassified information, or that operate, use, or connect to National Security Systems (NSS). This document is incorporated by reference as a source for definitions.

For each non-cloud FIS developed, implemented, operated, or maintained, paragraph (f) of the clause 52.239-YY requires contractors to apply NIST SP guidance on various topics when performing or managing certain activities related to the FIS, including: managing information system risk when supporting agency risk management activities; developing risk management processes; conducting and communicating the results of risk assessments; designing zero trust architecture approaches; considering security when executing within the context of systems engineering; selecting, adapting, and using cyber resiliency constructs for new systems, system upgrades, or repurposed systems; implementing continuous monitoring strategies for FISs; and implementing digital identity services and requirements. Further, paragraph (f)(7) requires contractors to provide the Government with a copy of their continuous monitoring strategy for the FIS that demonstrates an ongoing awareness of information security, vulnerabilities, and threats in order to support risk management decisions, and applies the use of automation, wherever possible; protects vulnerability scan data, logs, and telemetry; and applies the guidance of NIST SP 800-137, "Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations." Cyber supply chain risk management. Paragraph (g) of the clause 52.239-YY advises that contractors may implement alternative, additional, or compensating cyber supply chain risk management security controls from those stated in the contract, when authorized in writing to do so by the contracting officer. Notifiable incident reporting, incident response, and threat reporting. Paragraph (h) of the clause 52.239-YY reminds contractors that they must refer to FAR clause 52.239-ZZ, "Incident and Threat Reporting and Incident Response Requirements for Products or Services Containing Information and Communications Technology" (see FAR case 2021-017), for guidance on handling security incident and cyber threat reporting. Other protections. Paragraph (i) of the clause 52.239-YY specifies the limitations on contractor access to, use, and disclosure of Government data, Government-related data, and metadata under the contract, and requires contractors to notify the contracting officer of any requests from an entity other than the contracting activity (including warrants, seizures, or subpoenas the contractor receives from another Federal, State, or local agency) for access to Government data, Government-related data, or any associated metadata. The clause also notifies contractors that they must also comply with applicable clauses, regulations, and laws regarding unauthorized disclosure. Cryptographic Key Services.

, but only to the extent that such material would reveal the identity of a confidential source. (C) Portions of this system of records are exempt from the following subsections of 5 U.S.C. 552a : (d)(1-5). (ii) Authority. 5 U.S.C. 552a(k)(1) and (k)(5) . (iii) Reasons. (A) Granting individuals access to information collected and maintained in this system of records could result in the disclosure of classified material; and jeopardize the safety of informants, and their families. Further, the integrity of the system must be ensured so that complete and accurate records of all adjudications are maintained. Amendment could cause alteration of the record of adjudication. (B) [Reserved] (15) System identifier and name. N05580-1, Security Incident System. (i) Exemption. (A) Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2) if the information is compiled and maintained by a component of the agency which performs as its principal function any activity pertaining to the enforcement of criminal laws. (B) Portions of this system of records are

exempt from the following subsections of the Privacy Act: (c)(3), (c)(4), (d), (e)(2), and (e)(4)(G) through (I), (e)(5), (e)(8), (f) and (g). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons.

(A) Granting individuals access to information collected and maintained by this component relating to the enforcement of criminal laws could interfere with orderly administration of justice, and possibly enable suspects to avoid detection or apprehension. Disclosure of this information could result in concealment, destruction, or fabrication (printed page 14768) of evidence, and jeopardize the safety and well being of informants, witnesses and their families, and of law enforcement personnel and their families. Disclosure of this information could also reveal and render ineffectual investigative techniques, sources, and methods used by this component, and could result in the invasion of privacy of individuals only incidentally related to an investigation. The exemption of the individual's right of access to his or her records, and the reason therefore, necessitate the exemption of this system of records from the requirements of other cited provisions.

(B) [Reserved] (16) [Reserved] (17) System identifier and name. N05800-1, Legal Office Litigation/Correspondence Files. (i) Exemptions. (A) Information specifically authorized to be classified under E.O. 12958 , as implemented by DOD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1) . (B) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source.

ays. This project has resulted in The Computer Forensics Tool Testing Program (CFTT) is a project of ITL's Software and Systems Division (SSD) and is supported by the Special Programs Office and DHS. In FY 2019, several key advances were made to help address a critical need in the law enforcement community to ensure the reliability of computer forensic tools.

In an open-ended question, we also asked what other job functions or roles the participants had in addition to their security awareness responsibilities. All but two participants had other substantial cybersecurity duties beyond awareness training, for example, incident response, supply chain risk management, audits and compliance, policy, information systems security management, privacy awareness and training, cybersecurity role-based training, and project management.

Allowance for outsourced IT services Increased total time for the contractor to prepare for the assessment, including limited time for learning the reporting and affirmation processes Allowance for use of consulting firms to assist with the assessment process Time for a senior level manager to review the assessment and affirmation before submitting the results into SPRS Updated government and contractor labor rates that include applicable burden costs As a result, some CMMC 2.0 costs may be higher than those included in CMMC 1.0. (b) Assumptions for CMMC 2.0 Cost Analysis In estimating the public cost for a small defense contractor to achieve CMMC compliance or certification at each CMMC level, DoD considered non-recurring engineering costs, recurring engineering costs, assessment costs, and affirmation costs for each CMMC Level. These costs include labor and consulting. Estimates include size and complexity assumptions to account for typical organizational differences between small companies and others with respect to the handling of Information Technology (IT) and cybersecurity: small entities are likely to have a less complex, less expansive operating environment and IT/Cybersecurity infrastructure compared to larger defense contractors small entities are likely to outsource IT and cybersecurity to an External Service Provider (ESP) entities (small and other than small) pursuing CMMC Level 2 Self-Assessment are likely to seek consulting or implementation assistance from an ESP to either help them prepare for the assessment technically or participate in the assessment with the C3PAOs. Estimates do not include implementation (Non-recurring Engineering Costs (NRE)) or maintenance costs (Recurring Engineering (RE) [55]) for requirements prescribed in current regulations. For CMMC Levels 1 and 2, cost estimates are based upon assessment, reporting, and affirmation activities which a contractor will take to validate conformance with existing cybersecurity requirements from the FAR clause 52.204-21, effective June 15, 2016, to protect FCI, and the DFARS clause 252.204-7012 which required implementation of NIST SP 800-171 Rev 2 not later than December 31, 2017, to protect CUI. As such, cost estimates are not included for an entity to implement the CMMC Level 1 or 2 security requirements, maintain compliance with current security requirements, or remediate a Plan of Action for unimplemented requirements. For CMMC Level 3, the cost estimates factor in the assessment, reporting, and affirmation activities in addition to estimates for NRE and RE to implement and

maintain CMMC Level 3 security requirements. CMMC Level 3 security requirements are a selection of NIST SP 800-172 Enhanced Security Requirements as described in 32 CFR 170.14(c)(4) and are not currently required through other regulations. DoD expects that CMMC Level 3 will apply only to a small subset of defense contractors and subcontractors. The Cost Categories used for each CMMC Level are described:

The DoD certifies that this final rule would not, if promulgated, have a significant economic impact on a substantial number of small business entities in accordance with the Regulatory Flexibility Act (5 U.S.C. 601) requirements since a contractor cleared legal entity may, in entering into contracts requiring access to classified information, negotiate for security costs determined to be properly chargeable by a GCA. The DoD invites comment from members of the public who believe there will be a significant impact. Small entities to which this rule will apply provide products and services to the executive branch, e.g., in the areas of administration, consulting, information security and technology, cybersecurity, research and development, design, production and manufacturing, including circumstances where physical security measures cannot preclude aural or visual access to classified information. These small business entities, as well as non-small business entities, have entered into a contract, license or grant for which access to classified information is required. Compliance with this rule, also referred to as the NISPOM, is levied by a FAR security requirements clause or equivalent. The requirements for an entity eligibility determination do not include USG collection of applicable North American Industry Classification System (NAICS) codes. While this type of information is available in the Federal Procurement Data System (FPDS), entity eligibility determinations (often referred to as facility clearances) are not available in FPDS. DoD has no efficient mechanism to cross check NAICS codes from FPDS with facility clearance data. DoD assesses there are a wide variety of NAICS codes associated with contracts requiring access to classified information. For example, the following NAICS codes may be associated with contracts requiring access to classified information: 561720 janitorial services; 561210 facility support services; 541611 administrative management and general management services; 561110 office administrative services; 541690 other scientific and technical consulting services; 541330 engineering services; 561611 investigation services; and likely many others, since contracts that require a facility clearance for access to classified information are not industry specific.

(1) Contractor personnel make derivative classification decisions when they incorporate, paraphrase, restate, or generate in new form, information that is already classified. They must mark the newly developed material consistently with the classification markings that apply to the source information. (2) Derivative classification is the classification of information based on guidance from an OCA, which may be either a properly marked source document or a current security classification guide provided by a GCA in accordance with E.O. 13526 . The duplication or reproduction of existing classified information is not derivative classification. (3) A source document that does not contain portion markings, due to an ISOO-approved waiver, must contain a warning statement that it may not be used as a source for derivative classification in accordance with 32 CFR 2001.24(k)(4) . (4) Classified information in email messages is marked pursuant to E.O. 13526 and 32 CFR part 2001 . If an email is transmitted on a classified system, includes a classified attachment, and contains no classified information within the body of the email itself, the email serves as a transmittal document and is not a derivatively classified document. The email's overall classification must reflect the highest classification level present in the attachment. (c) Derivative classification responsibilities. Contractors will provide employees with pertinent classification guidance to fulfill their derivative classification responsibilities. All contractor employees authorized to make derivative classification decisions will: (1) Mark the face of each derivatively classified document with a classification authority block that includes the employee's name and position or personal identifier, the entity name, and when applicable, the division or the branch. Figure 1 to Paragraph (c)(1) Example of Industry Classification Authority Block UNCLASSIFIED: CLASSIFICATION MARKINGS FOR ILLUSTRATION PURPOSES ONLY Classified by: John Doe, Security Specialist, Entity ABC Security Division Derived From: SecDef Memo, dtd 20101024, Subj: ____ Declassify On: 20201024 (2) Observe and respect original classification decisions. (3) Carry forward the pertinent classification markings to any newly created documents. For information derivatively classified based on multiple sources, the derivative classifier will carry forward: (i) The date or event for declassification that corresponds to the longest period of classification among the sources. (ii) A listing of the source materials. (4) Be trained, in accordance with §.117.12(h), in the proper application of the derivative classification principles at least once every two years. (5) Whenever possible, use a classified addendum if classified

information constitutes a small portion of an otherwise unclassified document. (d) Security classification guidance. (1) Contractors should be aware the GCA will:

(c)(1) Providing a classified or unclassified notice of the determination made under paragraph (b) of this section. (i) In the case of a covered system included in the National Intelligence Program or the Military Intelligence Program, to the Select Committee on Intelligence of the Senate, the Permanent Select Committee on Intelligence of the House of Representatives, and the congressional defense committees; and (printed page 69272) (ii) In the case of a covered system not otherwise included in paragraph (a) of this section, to the congressional defense committees; and (2) The notice shall include. (i) The following information (see 10 U.S.C. 2304(f)(3)): (A) A description of the agency's needs. (B) An identification of the statutory exception from the requirement to use competitive procedures and a demonstration, based on the proposed contractor's qualifications or the nature of the procurement, of the reasons for using that exception. (C) A determination that the anticipated cost will be fair and reasonable. (D) A description of the market survey conducted or a statement of the reasons a market survey was not conducted. (E) A listing of the sources, if any, that expressed in writing an interest in the procurement. (F) A statement of the actions, if any, the agency may take to remove or overcome any barrier to competition before a subsequent procurement for such needs; (ii) The joint recommendation by the Under Secretary of Defense for Acquisition, Technology, and Logistics and the Chief Information Officer of the Department of Defense as specified in paragraph (a); (iii) A summary of the risk assessment by the Under Secretary of Defense for Intelligence that serves as the basis for the joint recommendation specified in paragraph (a); and (iv) A summary of the basis for the determination, including a discussion of less intrusive measures that were considered and why they were not reasonably available to reduce supply chain risk. 239.7305 Exclusion and limitation on disclosure. Subject to 239.7304, the individuals authorized in 239.7303 may, in the course of conducting a covered procurement. (a) Exclude a source that fails to meet qualification standards established in accordance with the requirements of 10 U.S.C. 2319 , for the purpose of reducing supply chain risk in the acquisition of covered systems; (b) Exclude a source that fails to achieve an acceptable rating with regard to an evaluation factor providing for the consideration of supply chain risk in the evaluation of proposals for the award of a contract or the issuance of a task or delivery order; (c) Withhold consent for a contractor to subcontract with a particular source or direct a contractor for a covered system to exclude a particular source from consideration for a subcontract under the contract; and

| URI | | |-----
-----|-----
-----| | SP 800-40 Revision 3, Guide to Enterprise Patch Management Technologies
<https://doi.org/10.6028/NIST.SP.800-40r3> | IT | | SP 800-46 Revision 2, Guide to
Enterprise Telework, Remote Access, and Bring Your Own Device (BYOD) Security
<https://doi.org/10.6028/NIST.SP.800-46r2> | OS | | SP 800-53 Revision 4, Security
and Privacy Controls for Federal Information Systems and Organizations
<https://doi.org/10.6028/NIST.SP.800-53r4> | IT | | SP 800-70 Revision 3, National
Checklist Program for IT Products: Guidelines for Checklist Users and Developers
<https://doi.org/10.6028/NIST.SP.800-70r3> | ... OS OS | | SP 800-83
Revision 1, Guide to Malware Incident Prevention and Handling for Desktops and Laptops
<https://doi.org/10.6028/NIST.SP.800-83r1> | OS | | SP 800-123, Guide to General
Server Security <https://doi.org/10.6028/NIST.SP.800-123> | ... | | SP 800-124 Revision 1, Guidelines
for Managing the Security of Mobile Devices in the Enterprise
<https://doi.org/10.6028/NIST.SP.800-124r1> | | | SP 800-125, Guide to Security for Full
Virtualization Technologies <https://doi.org/10.6028/NIST.SP.800-125> | | | SP 800-125A,
Security Recommendations for Hypervisor Deployment (Second Draft)
<https://csrc.nist.gov/publications/detail/sp/800-125A/draft> | | | SP 800-125B, Secure
Virtual Network Configuration for Virtual Machine (VM) Protection
<https://doi.org/10.6028/NIST.SP.800-125B> | | | SP 800-147, BIOS Protection

The Department declines to adopt the recommendation to allow DIB members to assist in designing the DoD's mechanism for assessing DIB compliance with DoD's contractual requirements. In developing the CMMC program, the DoD sought and considered DIB input. DoD disagrees with the comment that there is a lack of scalability in the CMMC program. The phased implementation plan described in §.170.3(e) is intended to address any CMMC Ecosystem ramp-up issues, provide time to train the necessary number of

assessors, and allow companies the time needed to understand and implement CMMC requirements. The rule has been updated to add an additional six months to the Phase 1 timeline. As with all its programs, the Department intends to effectively oversee the CMMC Program and act as needed to manage its effective implementation. Although the full extent of DoD's oversight process is beyond the scope of this rule, the rule text addresses DoD's authority to waive the application of CMMC requirements when warranted in accordance with all applicable policies, procedures, and approval requirements. DoD has utilized a phased approach to the rollout to reduce implementation risk. CMMC Program requirements make no changes to existing policies for information security requirements implemented by the DoD. It is beyond the scope of this rule for DoD to determine the order in which organizations are assessed. (printed page 83158) d. Alternate Assessors or Assessments (Including Self-Assessment Only) Comment: One commenter submitted numerous recommendations based on an opinion that skills required for conducting CMMC compliance assessments are like those required for conducting Independent Technical Risk Assessments (ITRAs) on Major Defense Acquisition Programs (MDAPs). Such assessments are conducted by the Office of the Undersecretary of Defense for Research & Engineering (OUSD(R&E)) in accordance with Defense Technical Risk Assessment Methodology (DTRAM) criteria. These criteria extend beyond compliance with cybersecurity requirements and include characteristics such as modular open systems architecture, software, manufacturing, reliability, availability, maintainability, and others. This commenter noted the DoD's Adaptive Acquisition Framework applies to both Information Systems and National Security Systems and suggested that existing acquisition requirements pertaining to ITRA and DTRAM should suffice in lieu of CMMC assessments. The commenter recommended that DoD use existing ITRA teams to perform compliance assessments of contractor-owned information systems. In addition, they recommended aligning requirements to DoD policies rather than to NIST standards. Other comments made similar suggestions to synchronize cybersecurity requirements with DoD policies rather than NIST standards but cited FISMA compliance assessments as the appropriate model rather than the DTRAM.

In response to public comments received in the initial 48 CFR CMMC interim final rule public comment period, DoD streamlined the CMMC model to ease the assessment burden. At the same time, estimates were increased for the time and cost of self-assessment based on industry and DIBCAC input. DoD estimates are based on defensible assumptions and documented labor rates. Therefore, DoD declines to modify the self-assessment estimates. The DoD has streamlined CMMC requirements to align directly to NIST guidelines and eliminated unique security practices to ease the burden on smaller companies, included an analysis of costs to meet CMMC requirements in the regulatory impact analysis for this rule. The DoD declined to modify the estimates, which are intended to be representative and to inform rulemaking. Verifying compliance with applicable security requirements may increase cost and is necessary for the protection of DoD CUI. The cost of lost technological advantage over potential adversaries is greater than the costs of such enforcement. The value of information (and impact of its loss) does not diminish when the information moves to contractors. DoD rejected the recommendation to adjust the annual requirement for senior affirmations to a triennial requirement to decrease senior affirmation costs. The requirement for annual affirmations is to ensure the Affirming Official responsible for CMMC requirements are monitoring compliance with the requirements. If compliance is being maintained as required, this should not require more time or cost than provided in the estimates. Further, DFARS clause 252.204-7012 already requires NIST SP 800-171 continuous monitoring via requirement 3.12.3. DoD also declined to make the recommended edits to further delineate a company's internal review of self-assessments and reaffirmations in the cost assumptions. The cost estimates provided for this rule represent average costs for (printed page 83155) companies to comply with the CMMC requirement, including the need for self-assessment or independent assessment against the specified standards. Whether the OSA elects to satisfy those requirements themselves, or by using one ESP for many requirements, or by using several ESPs for individual requirements, is a decision to be made by the OSA. That decision does not change DoD's estimate of average costs to meet CMMC requirements. The DoD declined to recalculate cost estimates using lower costs for ESP assessments.

by adding part 117 to read as follows: PART 117·NATIONAL INDUSTRIAL SECURITY PROGRAM OPERATING MANUAL (NISPOM) 117.1 Purpose. 117.2 Applicability. 117.3 Definitions. 117.4 Policy. 117.5 Information collections. 117.6 Responsibilities. 117.7 Procedures. 117.8 Reporting requirements. 117.9 Entity eligibility determination for access to classified information. 117.10 Determination of eligibility for access to classified information for contractor employees. 117.11 Foreign Ownership, Control, or Influence (FOCI). 117.12 Security training and briefings. 117.13 Classification. 117.14 Marking requirements. 117.15 Safeguarding classified information. 117.16

Visits and meetings. 117.17 Subcontracting. 117.18 Information system security. 117.19 International security requirements. 117.20 Critical Nuclear Weapon Design Information (CNWDI). 117.21 COMSEC. 117.22 DHS CCIPP. 117.23 Supplement to this rule: Security Requirements for Alternative Compensatory Control Measures (ACCM), Special Access Programs (SAPs), SCI, RD, Formerly Restricted Data (FRD), Transclassified Foreign Nuclear Information (TFNI), and Naval Nuclear Propulsion Information (NNPI). 117.24 Cognizant Security Office information. Authority: 32 CFR part 2004 ; E.O. 10865 ; E.O. 12333 ; E.O. 12829 ; E.O. 12866 ; E.O. 12968 ; E.O. 13526 ; E.O. 13563 ; E.O. 13587 ; E.O. 13691 ; Public Law 108-458 ; Title 42 U.S.C. 2011 et seq. ; Title 50 U.S.C. Chapter 44; Title 50 U.S.C. 3501 et seq. § 117.1 Purpose. (a) This rule implements policy, assigns responsibilities, establishes requirements, and provides procedures, consistent with E.O. 12829 , ·National Industrial Security Program·; E.O. 10865 , ·Safeguarding Classified Information within Industry·; 32 CFR part 2004 ; and DoD Instruction (DoDI) 5220.22, ·National Industrial Security Program (NISP)· (available at <https://www.esd.whs.mil/Portals/54/ Documents/DD/issuances/dodi/522022p.pdf?ver=2018-05-01-073158-710>) for the protection of classified information that is disclosed to, or developed by contractors of the U.S. Government (USG) (hereinafter referred to in this rule as contractors). (b) This rule, also in accordance with E.O. 12829 , E.O. 13587 , ·Structural Reforms To Improve the Security of Classified Networks and the Responsible Sharing and Safeguarding of Classified Information·; E.O. 13691 , ·Promoting Private Sector Cybersecurity Information Sharing·; E.O. 12333 , ·United States Intelligence Activities·; 42 U.S.C. 2011 et seq. (also known as and referred to in this rule as the ·AEA of 1954,· as amended); · 50 U.S.C. Ch. 44 (also known as the ·National Security Act of 1947,· as amended); 50 U.S.C. 3501 et seq. (also known as the ·Central Intelligence Agency Act of 1949,· as amended); Public Law 108-458 (also known as the ·Intelligence Reform and Terrorism Prevention Act of 2004·); and 32 CFR part 2004 : (1) Prescribes industrial security procedures and practices, under E.O. 12829 or successor orders, to safeguard USG classified information that is developed by or disclosed to contractors of the USG.

stock purchase, asset purchase), the identity of the potential foreign interest investor, and a plan to negate or mitigate the FOCI by a method outlined in paragraph (d) of this section. (ii) The entity will submit copies of loan, purchase, and shareholder agreements, annual reports, bylaws, articles of incorporation, partnership agreements, other organizational documents, and reports filed with other Federal agencies to the CSA. (d) FOCI action plans. (1) When FOCI factors not related to ownership are present, the CSA will determine if positive measures will assure the CSA that the foreign interest can be effectively mitigated and cannot otherwise adversely affect performance on classified contracts. Examples of such measures include: (i) Modification or termination of loan agreements, contracts, and other understandings with foreign interests. (ii) Diversification or reduction of foreign-source income. (printed page 83332) (iii) Demonstration of financial viability independent of foreign interests. (iv) Elimination or resolution of problem debt. (v) Assignment of specific oversight duties and responsibilities to board members. (vi) Formulation of special executive-level security committees to consider and oversee issues that affect the performance of classified contracts. (vii) Physical or organizational separation of the contractor component performing on classified contracts. (viii) Adoption of special board resolutions. (ix) Other actions that negate or mitigate foreign control or influence. (x) A combination of these methods, as determined by the CSA. (2) When FOCI factors related to ownership are present, methods the CSA may apply to negate or mitigate the risk of foreign ownership include, but are not limited to: (i) Board resolution. (A) When a foreign interest does not possess voting interests sufficient to elect, or otherwise is not entitled to representation on the entity's governing board, a resolution(s) by the governing board may be adequate. In the resolution, the governing board will: (1) Identify the foreign shareholder. (2) Describe the type and number of foreign-owned shares. (3) Acknowledge the entity's obligation to comply with all industrial security program requirements. (4) Certify that the foreign owner does not require, will not have, and can be effectively precluded from unauthorized access to all classified information entrusted to or held by the entity. (B) The governing board will provide for annual certifications to the CSA acknowledging the continued effectiveness of the resolution. (C) The entity will distribute to members of its governing board and to its KMP copies of such resolutions, and report in the entity's corporate records the completion of such distribution. (ii) Security control agreement (SCA). When a foreign interest does not effectively own or control an entity (i.e.,

The intent is to increase the effectiveness, efficiency, and cost-effectiveness of the RMF by establishing a closer connection to the organization's missions and business functions and

(d) The Deputy Assistant Secretary of the Army (Civilian Personnel Policy)/Director of Civilian Personnel, Office of the Assistant Secretary of the Army (Manpower and Reserve Affairs) is authorized to act on requests for civilian personnel records, personnel administration and other civilian personnel matters, except for EEO (civilian) matters which will be acted on by the Administrative Assistant to the Secretary of the Army. The Deputy Assistant Secretary of the Army (Civilian Personnel Policy)/Director of Civilian Personnel has delegated this authority to the Chief, Policy and Program Development Division (Note: Requests from former civilian employees to amend a record in an Office of Personnel Management system of records, such as the Official Personnel Folder, should be sent to the Office of Personnel Management, Assistant Director for Workforce Information, Compliance, and Investigations Group: 1900 E. Street, NW., Washington, DC 20415-0001). (e) The Chief Information Officer G-6 is authorized to act on requests for records pertaining to Army Information Technology, command, control communications and computer systems and the Information Resources Management Program (automation, telecommunications, visual information, records management, publications and printing). (f) The Inspector General is authorized to act on requests for all Inspector General Records. (g) The Auditor General is authorized to act on requests for records relating to audits done by the U.S. Army Audit Agency under AR 10-2. This includes requests for related records developed by the Audit Agency. (h) The Director of the Army Staff is authorized to act on requests for all records of the Chief of Staff and its Field Operating Agencies. The Director of the Army Staff has delegated this authority to the Chief Attorney and Legal Services Directorate, U.S. Army Resources & Programs Agency (See The Judge Advocate General for the General Officer Management Office actions). The Chief Attorney and Legal Services Director, U.S. Army Resources & Programs Agency acts on requests for records of the Chief of Staff and its Field Operating Agencies (See The Judge Advocate General for the General Officer Management Office actions). (i) The Deputy Chief of Staff, G-3/5/7 is authorized to act on requests for records relating to International Affairs policy, planning, integration and assessments, strategy formulation, force development, individual and unit training policy, strategic and tactical command and control systems, nuclear and chemical matters, use of DA forces. (j) The Deputy Chief of Staff, G-8 is authorized to act on requests for records relating to programming, material integration and externally directed reviews.

Management provides mechanisms for maintaining attributes to ensure the efficiency and consistent use of attributes, including metadata, hierarchical structures for attribute grouping, minimization and transformation methods for attribute performance, and additional support capabilities (e.g., attribute integration with authentication, logs for recording attribute access and updates). | |

Executive Summary.....
..... | Executive Summary.....
..... | iv | |-----

-|-----
-----|-----| 1 | Introduction.....
..... | Introduction
.....
.....

In accordance with laws, Executive Orders, directives, policies, regulations, or standards, the public is not authorized access to nonpublic information (e.g., information protected under the Privacy Act, CUI, and proprietary information). This requirement addresses systems that 54 NIST SP 800-171A, p. 18. 55 NIST SP 800-171 Rev. 2, p. 16.

ounting for developing country interests). 12 - - The International Strategy for Cyberspace 13 lays out an approach to unify USG engagement with international partners on a full range of cyber issues. The International Strategy highlights the need to develop and use international cybersecurity

standards and conformity assessment schemes, and the importance of public-private sector collaboration. The Strategy establishes the goal that '[t]he United States will work internationally to promote an open, interoperable, secure, and reliable information and communications infrastructure that supports international trade and commerce, strengthens international security, and fosters free expression and innovation.' The strategy contains policy priorities for the economy; protecting our networks; law enforcement; military; internet governance; international development; and internet freedom. This includes steps to enhance confidence in cyberspace and pursue those who would exploit online systems, and a commitment from the USG to participate actively in discussions about how international norms and measures on cybercrime are developed bilaterally and multilaterally, in fora with proven expertise and a history of promoting effective cybercrime policies. This also includes promoting processes to permit states to investigate, apprehend, and prosecute those who intrude or disrupt networks. - - The National Cooperative Research Act of 1984 14 first allowed organizations to collaborate to carry out joint research and development ventures and not be deemed illegal per se under federal antitrust laws or similar State laws. One result has been a rapid growth in IT consortia developing standards. In developing their standards, many of these consortia follow the WTO TBT Committee Decision principles. However, consortia are also formed that are not open, with membership by invitation.

Most compliance activities would be performed by a workforce member at the hourly wage rate of an information security analyst (\$119.94), while documentation of maintenance would be performed at the rate of a management analyst (\$111.08) and notification of termination or change of workforce members' access to ePHI would be performed by an office administrative assistant (\$46.10). This would result in estimated total first year costs for health plan sponsors of \$4,658,781,219 as shown in detail in table 7. o. Total Quantifiable Costs The Department summarizes in tables 6 and 7 the estimated costs that regulated entities (approximately \$4,655 million) and plan sponsors (approximately \$4,659 million), respectively, would experience in the first year of implementing the proposed regulatory changes. The Department anticipates that these costs would be for the following activities: conducting a Security Rule compliance audit; obtaining verification of business associates' and subcontractors' compliance with technical safeguards; providing verification of business associates' compliance with technical safeguards; providing notification of termination or change of workforce members' access to ePHI; deploying MFA and penetration testing; segmenting networks; disabling unused ports; removing extraneous software; notifying covered entities or business associates, as applicable, upon activation of a contingency plan; and updating health plan documents, policies and procedures, workforce training, and business associate agreements. These costs would also include health plan sponsors deploying safeguards for their relevant electronic information systems to meet Security Rule standards and notifying group health plans upon activation of a plan sponsor's contingency plan. Table 6-First Year Cost Estimates for Regulated Entities' Proposed Compliance Obligations

Activity	Wage rate	Burden hours	Frequency	Respondents	Total annual cost (millions)
Security Rule Compliance Audit	\$119.94	2	1	1,822,600 Regulated Entities	\$437
BA Verification of Technical Safeguards	\$119.94	2	1	1,000,000 Business Associates	240
Obtain BA Compliance Verification	\$119.94	.5	1	822,600 Covered Entities	49
Obtain Subcontractors' Compliance Verification	\$119.94	.083	1	1,000,000 Business Associates	10
Notification of Workforce Members' Termination of access to ePHI	\$119.94	1	1	1,822,600 Regulated Entities	46.10
Multi-factor Authentication	\$119.94	1.5	1	1,822,600 Regulated Entities	\$328
Network Segmentation	\$119.94	4.5	1	1,822,600 Regulated Entities	984
Configuration Management	\$119.94	.5	1	1,395,396 Regulated Entities	69.20
Penetration Testing	\$119.94	3	1	1,822,600 Regulated Entities	656
Notification of Contingency Plan Activation	\$119.94	.5	1	1,000,000 Business Associates	60
Update Health Plan Documents	\$119.94	.5	120	3,102,851 Health Plan Documents	145.14
Update Policies and Procedures	\$119.94	3.5	1	1,822,600 Regulated Entities	173.76
Update Workforce Training	\$119.94	2	1	1,822,600 Regulated Entities	252

For access to the docket to read background documents or comments received, go to <http://www.regulations.gov> and insert the docket number, found in brackets in the heading of this document, into the 'Search' box and follow the prompts and/or go to the Division of Dockets Management, 5630 Fishers Lane, rm. 1061, Rockville, MD 20852. FOR FURTHER INFORMATION CONTACT: Lisa Berry, Office of Financial Management, (printed page 67821) Food and Drug Administration, 1350 Piccard Dr., suite 200A, Rockville, MD 20850, 301-796-7225. SUPPLEMENTARY INFORMATION: I. Description of the System of Records The UFS is a billing and collections system that maintains information about the individuals, organizations, and companies required to pay user fees.

Information maintained in the UFS includes: Contact person's name, phone number, fax number, and email address; Federal Employer Identification Number (FEIN) for entity remitters; Taxpayer Identification Number (TIN) for individual remitters, which is encrypted with only the last four characters visible (in some circumstances individual remitters may use a Social Security Number as the TIN); Company name or the Organization name; and Data Universal Numbering System (DUNS) number and business address. The UFS also stores application details as the fee remitter (submitter) creates coversheets to pay user fees. These details include, but are not limited to, the type of application, waiver and exemption status, and Small Business Decision (SBD) Number. When a submitter generates a coversheet the UFS will only print the last four characters of the FEIN/TIN along with the organization name and address. Additionally, the UFS stores billing details, adjustments to invoices, and payment receipt information including date, mode, and amount of payment.

II. Routine Use Disclosures of Information in the System The Privacy Act allows FDA to disclose information without an individual's consent if the information is to be used for a purpose that is compatible with the purpose(s) for which the information was collected. Any such compatible use of data is known as a routine use. The routine uses in this system meet the compatibility requirement of the Privacy Act.

(C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (D) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(1), (k)(2) and (k)(5) from subsections 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (E) To the extent that copies of exempt records from external systems of records are entered into A0381-10b DAMI, the Army hereby claims the same exemptions for those records as claimed for the original primary system of which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2), and (k)(1) through (k)(7). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (G) For records that are copies of exempt records from external systems of records, such records are only exempt from pertinent provisions of 5 U.S.C. 552a

An Authority to Operate (ATO) is a formal declaration by an authorizing official that a federal information system is approved to operate at an acceptable level of risk. ATOs are part of the NIST Risk Management Framework (SP 800-37). In the context of defense contractors and CMMC: - Federal agencies issue ATOs for their own systems - FedRAMP issues ATOs (or Provisional ATOs / P-ATOs) for cloud service providers - CMMC certification is analogous to an ATO for contractor systems handling CUI A FedRAMP ATO/P-ATO indicates that a cloud service has been assessed against NIST SP 800-53 controls and authorized for federal use. Contractors using cloud services for CUI should verify the CSP has a FedRAMP Moderate (or equivalent) ATO per DFARS 252.204-7012.

(9) Provide the CMMC PMO with current data on C3PAOs, including authorization and accreditation records and status in the CMMC instantiation of eMASS. This data shall include the dates associated with the authorization and accreditation of each C3PAO. (10) Provide the DoD with information about aggregate statistics pertaining to operations of the CMMC Ecosystem to include the authorization and

accreditation status of C3PAOs or other information as requested. (11) Provide inputs for assessor supplemental guidance to the CMMC PMO. Participate and support coordination of these and other inputs through DoD-led Working Groups. (12) Ensure that all information about individuals is encrypted and protected in all Accreditation Body information systems and databases. (13) Provide all plans that are related to potential sources of revenue, to include but not limited to: fees, licensing, processes, membership, and/or partnerships to the Department's CMMC PMO. (14) Ensure that the CMMC Assessors and Instructors Certification Organization (CAICO) is compliant with ISO/IEC 17024:2012. If ISO/IEC 17024:2012 is revised or superseded, the Accreditation Body shall require full compliance with the updated standard within 12 months of the date of revision. (15) Ensure all training products, instruction, and testing materials are of high quality and subject to CAICO quality control policies and procedures, to include technical accuracy and alignment with all applicable legal, regulatory, and policy requirements. (16) Render a final decision on all elevated appeals. (17) Develop and maintain a comprehensive plan and schedule to comply with all ISO/IEC 17011:2017, or subsequent revisions, and DoD requirements for Conflict of Interest, Code of Professional Conduct, and Ethics policies as set forth in the DoD contract. All policies shall apply to the Accreditation Body, and other individuals, entities, and groups within the CMMC ecosystem who provide CMMC assessments, CMMC instruction, CMMC training materials, or CMMC certification on behalf of the Accreditation Body. All policies in this section must be approved by the CMMC PMO prior to effectivity in accordance with the following requirements. (i) Conflict of Interest (CoI) Policy. The CoI policy shall: (A) Include a detailed risk mitigation plan for all potential conflicts of interest that may pose a risk to compliance with ISO/IEC 17011:2017, or subsequent revisions. (B) Require members of the Accreditation Body to disclose to the CMMC PMO, in writing, as soon as it is known or reasonably should be known, any actual, potential, or perceived conflict of interest with sufficient detail to allow for assessment. (C) Require members of the Accreditation Body who leave the board or organization to enter a ·cooling off period· of six (6) months whereby they are prohibited from working with the Accreditation Body or participating in CMMC activities.

One comment states that it is a member of the International Flight Catering Association and International Inflight Food Service Association and adheres to practices of the ·World Food Safety Guideline· as set forth by the two associations of inflight food services. Another comment states that all employees have been certified by the FAA through fingerprinting and 10-year background checks, and inhouse security personnel are responsible for checking what is placed on aircraft. Another comment maintains control of all inputs and outputs of production and states that documentation is in place for all items received and for all items produced. (Response) For the reasons stated in response to comment 76 of this document, FDA continues to believe that facilities that provide food to interstate conveyances should not be covered by the restaurant exclusion because they do not provide food directly to consumers for immediate consumption. However, these final regulations state that duplication of existing records is not required if those records contain all of the information required by subpart J of this final rule. Therefore, if a covered person keeps records of all of the information as required by subpart J in order to comply with other Federal, State, or local regulations, or for any other reason, then those records may be used to meet these requirements. As the comment notes, the airline catering industry currently has the capability to trace all food products on their flights. These regulations do not dictate the format or system in which the required records are maintained. The airline catering industry can use existing tracing mechanisms to comply with these regulations to the extent those mechanisms contain the required information.

SC.L2-3.13.8 · Data in Transit CMMC Assessment Guide · Level 2 | Version 2.13 227 SC.L2-3.13.8 · DATA IN TRANSIT Implement cryptographic mechanisms to prevent unauthorized disclosure of CUI during transmission unless otherwise protected by alternative physical safeguards. ASSESSMENT OBJECTIVES [NIST SP 800-171A]201 Determine if: [a] cryptographic mechanisms intended to prevent unauthorized disclosure of CUI are identified; [b] alternative physical safeguards intended to prevent unauthorized disclosure of CUI are identified; and [c] either cryptographic mechanisms or alternative physical safeguards are implemented to prevent unauthorized disclosure of CUI during transmission. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]

KENT: There are two basic methods of using the DES, each having certain advantages and disadvantages. The first is block mode, or "electronic code book" mode. In this mode 64 bits of data are encrypted at a time and each such 64-bit block is encrypted independent of any other block. The second method is cipher feedback mode in which normally a character at a time is encrypted by using

the last 64 bits of cipher that were generated as input to the DES and using a number of the output bits to XOR with the character to produce the cipher. This cipher is used as input for the next encryption operation. Cipher feedback is most useful for character oriented communications or for the encryption of serial data for storage. Cipher feedback cannot be used to encrypt storage files that are to be randomly accessed. It cannot be used for encryption across packets in packet switching networks since decryption is serial dependent and packets often arrive out of order. Block mode is faster than cipher feedback, but cipher feedback is self synchronizing and provides message integrity. There was considerable give and take discussion during and following some of the presentations. To preserve the integrity of the presentations, this discussion is grouped together in this section. Following Mr. Pyke's presentation on the preceeding workshop concerning a hardware device to do 'brute force' key searching, the discussion was particularly wide ranging.

, the Department estimates that business associates that handle ePHI would need to spend an average of 2 hours (with a low estimate of 0.25 hours and high estimate of 2.5 hours) analyzing how their cybersecurity measures comply with the proposed requirements for technical safeguards and producing a verification report for covered entities at the hourly wage rate of an information security analyst. This estimate assumes that business associates have already documented existing safeguards, policies, and procedures, so that the costs attributable to the new requirement are incremental and would total approximately \$239,880,000 [1 million business associates × 2 hours × \$119.94], with a low estimate of \$29,985,000 [1 million business associates × 0.25 hours × \$119.94] and high estimate of \$299,850,000 [1 million business associates × 2.5 hours × \$119.94]. c. Costs Arising From Covered Entities and Business Associates Obtaining Verification From Business Associates of Compliance With Technical Safeguards Under 45 CFR 164.308(b) , the Department further estimates that each covered entity would need to spend an average of 30 minutes (with 15 minutes as a low estimate and 90 minutes as a high estimate) requesting and obtaining compliance reports from its business associates about their deployment of technical safeguards required by the Security Rule at the hourly wage of an information security analyst. This assumes that in most instances, business associates would produce the required verification for covered entities without being prompted by a request because they would be required to do so by the Security Rule, as proposed in the NPRM. It further assumes that covered entities have readily available means of contacting business associates, such as via email, and that the contact could be a single email draft sent in a batch. The average time burden per entity depends on verification frequency, likely influenced by entities' average number of business associates and how frequently entities change business associates. The low estimate assumes that entities verify less frequently, whereas the high estimate assumes entities verify more frequently. At the wage rate of an information security analyst, this would result in estimated total costs for covered entities of \$49,331,322 [= 822,600 covered entities × 0.5 hours × \$119.94], with a low estimate of \$24,665,661 [= 822,600 covered entities × 0.25 hours × \$119.94] and high estimate of \$147,993,966 [= 822,600 covered entities × 1.5 hours × \$119.94].

means a transportation protective service provided by a commercial carrier qualified by the Surface Deployment and Distribution Command to transport CONFIDENTIAL shipments. The service requires constant surveillance of the shipment at all times by a qualified carrier representative; however, an FCL is not required for the carrier. The carrier providing the service must maintain a signature and tally record for the shipment. Consultant means an individual under contract, and compensated directly, to provide professional or technical assistance to a contractor in a capacity requiring access to classified information. Continuous evaluation as defined in SEAD 6 is a personnel security investigative process to review the background of a covered individual who has been determined to be eligible for access to classified information or to hold a sensitive position at any time during the period of eligibility. Continuous evaluation leverages a set of automated records checks and business rules, to assist in the ongoing assessment of an individual's continued eligibility. It supplements, but does not replace, the established personnel security program for scheduled periodic reinvestigations of individuals for continuing eligibility. Continuous monitoring program means a system that facilitates ongoing awareness of threats, vulnerabilities, and information security to support organizational risk management decisions. Contracting officer means a USG official who, in accordance with departmental or agency procedures, has the authority to enter into and administer contracts, licenses or grants and make determinations and findings with respect thereto, or any part of such authority. The term also includes the designated representative of the contracting officer acting within the limits of his or her authority. Contractor means any industrial, educational, commercial, or other entity that has been granted an entity eligibility determination by a CSA. This term also includes licensees, grantees, or certificate holders of the

USG with an entity eligibility determination granted by a CSA. As used in this rule, ·contractor· does not refer to contractor employees or other personnel. Cooperative agreement means a legal instrument which, consistent with 31 U.S.C. 6305, is used to enter into the same kind of relationship as a grant (see definition of ·grant· in this subpart), except that substantial involvement is expected between USG and the recipient when carrying out the activity contemplated by the cooperative agreement. The term does not include ·cooperative research and development agreements· as defined in 15 U.S.C. 3710a. (printed page 83315) Cooperative research and development agreement

National intelligence is under the jurisdiction and control of the DNI, who establishes security policy for the protection of national intelligence and intelligence sources, methods, and activities. In addition to the guidance in this rule, contractors will follow Intelligence Community directives, policy guidance, standards, and specifications for the protection of classified national intelligence and SCI. (c) ACCM. Contractors may participate in ACCMs, or be directed to participate, only when such access and the associated security plan are identified in DD Form 254 or equivalent. Care must be taken to ensure identification of the security plan does not disclose ACCM-protected data. (1) ACCM contracts. DoD contractors will implement the security requirements for ACCMs, when established by contract, in accordance with applicable statutes, E.O.s, CSA directives, instructions, manuals, regulations, standards, and memorandums. (2) Non-DoD with ACCMs. Contractors performing on ACCM contracts issued by other than DoD GCAs will implement ACCM protection requirements imposed in their contracts. (d) SAPs. (1) DoD SAP contracts. Contractors will implement the security requirements for SAPs codified in SAP-related policy, when established by contract. These documents include, but are not limited to, statutes, E.O.s, CSA directives, instructions, manuals, regulations, standards, memorandums, and other SAP security related policy documents. (2) Non-DoD SAPs. Contractors performing on SAP contracts issued by non-DoD GCAs will implement SAP protection requirements imposed in their contracts. These requirements may be from, but are not limited to, statutes, E.O.s, CSA directives, instructions, manuals, regulations, standards, memorandums, and other SAP security related policy documents. (e) RD, FRD, and TFNI. (1) General. This section describes some of the requirements for nuclear-related information designated RD, FRD, or TFNI in accordance with the AEA and 10 CFR part 1045. 10 CFR part 1045 contains the full requirements for classification and declassification of RD, FRD, and TFNI. Information on safeguarding of RD by access permittees is contained in 10 CFR part 1016. For RD that is NNPI, the additional provisions of paragraph (f) of this section apply. (i) The DOE is the sole authority for establishing requirements for classifying, accessing, handling, securing, and protecting RD. The DOE and the DoD share authority for the requirements for FRD. The DOE and ODNI share authority for establishing requirements for TFNI. (ii) RD, FRD, and TFNI categories are distinguished from the NSI category, which is governed in accordance with E.O. 13526. (A) RD, FRD, and TFNI have unique marking requirements and are not subject to automatic declassification. In addition, RD and FRD have special restrictions regarding foreign release. (B) It is necessary to differentiate between the handling of this information and NSI because of its direct relationship to our nation's nuclear deterrent.

information technology (IT)) and those that run the vital machinery that ensures its safety (e.g., operational technology (OT)). The Government contracts with IT and OT service providers to conduct an array of day-to-day functions on Federal Information Systems (FIS). A FIS is an information system used or operated by an agency, by a contractor of an agency, or by another organization, on behalf of an agency. All FISs require protection as part of good risk management practices. Agencies are responsible for determining what information systems are FIS, in accordance with the definition provided in this rule. Currently, contractual requirements for the cybersecurity standards of unclassified FISs are largely based on agency-specific policies and regulations. The risks associated with agency-specific policies can result in inconsistent security requirements across contracts, as well as be unclear, add costs, and restrict competition. To address these risks, paragraph (i) of section 2 of E.O. 14028 requires the DHS Secretary, acting through the Director of CISA, to review agency-specific cybersecurity requirements that currently exist as a matter of law, policy, or contract and recommend to the FAR Council standardized contract language for appropriate cybersecurity (printed page 68403) requirements. Paragraph (j) of section 2 of E.O. 14028 then directs that FAR Council to consider the contract language received from DHS and publish for public comment any proposed updates to the FAR. This proposed rule would implement the DHS recommendations across all Federal agencies to streamline requirements and improve compliance for contractors and the Government. By standardizing a set of minimum cybersecurity standards to be applied

consistently to FISS, the proposed rule would ensure that such systems are better positioned in advance to protect from cyber threats. In addition, and as required by paragraph (k) of section 2 of E.O. 14028, upon issuance of a final rule, agencies shall update their agency-specific requirements to remove any requirements that are duplicative of such FAR updates. II. Discussion and Analysis This proposed rule provides cybersecurity policies, procedures, and requirements for contractor services to develop, implement, operate, or maintain a FIS. This rule underscores that compliance with these requirements is material to eligibility and payment under Government contracts. A contract to develop, implement, operate, or maintain a FIS may require contractors to utilize cloud computing services, services other than cloud computing services (i.e., non-cloud computing services, also known as on-premises computing services), or a hybrid of both approaches when providing services under the contract. As such, this rule specifies the policies, procedures, and requirements that apply to each service approach (i.e.,

This rule retains the reference to DFARS clause 252.204-7012 that implements NIST SP 800-171 as the basis for the requirement to create and update an SSP. The DoD has considered the recommended changes to the rule regarding the SSP content and declines to make the revision. The NIST SP 800-171 R2 requirement for an SSP is foundational to performing a NIST SP 800-171 R2 self-assessment and its purpose is to provide critical information for performing the assessment. The SSP should detail the policies and procedures that support . . . how security requirements are implemented . . . for all NIST SP 800-171 R2 controls. DoD declines to establish a specific SSP format, as OSAs should define the best format for their organizations. The Overview section of the rule has been updated to remove the statement indicating SSPs will outline the roles and responsibilities of security personnel. DoD does not plan to provide document templates for SSPs and POA&Ms, as they are already available (printed page 83132) in existing NIST guidance. Templates and schemas for the pre-assessment and assessment results documents are available to authorized CMMC eMASS users at <https://cmmc.emass.apps.mil>. Commenter concerns about artifact retention reflect misunderstanding of the assessment process. Assessors and C3PAOs do not retain OSC artifacts, they only retain the hash value captured during the assessment process. Assessors will retain documents created during the assessment such as their notes and the Assessment Findings Reports. To facilitate the protection of these documents, authorized C3PAOs are required to go through a DIBCAC conducted CMMC Level 2 assessment and CMMC Assessors are only authorized to use C3PAO issued equipment that was within the scope of the DIBCAC assessment. Separately, the DIBCAC processes, stores, and transmits its assessment related data on DoD networks. Assessment Reports are submitted to DoD via eMASS, which is a government-owned, secured database. Sharing of this information is subject to DoD policies. The OSC is responsible for maintaining and hashing all artifacts that supported the assessment. The rule has been modified to clarify C3PAOs do not maintain artifacts from the OSC. The OSC's artifacts must be hashed, and the value provided to the assessor for submission into CMMC eMASS. That hash value contains no sensitive information. An OSC's System Security Plan (SSP) will be reviewed as part of a CMMC certification assessment, but not shared outside of the OSC. Assessors will not retain copies of the SSP or any other proprietary OSC information. Assessors will retain the name, date, and version of the SSP for uploading in SPRS or eMASS, as appropriate for the level of assessment. Assessors will upload assessment information (e.g.,

Added a caveat in the clause at 252.245-7004(b)(1) to use the Plant Clearance Automated Reutilization Screening System unless disposition instructions are otherwise included in the contract; Relocated paragraph (e) of the 252.245 clause to paragraph (j) to better align language with actual process; Deleted ~~Commerce control list~~ and ~~Munitions list items~~ from the definitions and added definitions of ~~Export-controlled items~~ and ~~Ineligible transferees~~ to the clause at 252.245-7004(a); Added the terms ~~mutilation/destruction~~ and ~~mutilate/destroy~~, as appropriate, after each instance of the term ~~demilitarization~~ for consistency with DoD policy; Deleted supply condition codes from 252.245-7004(b)(1), and added a hyperlink to DoD 4000.25-2-M; Added clarifying language for disposition of contractor inventory located in foreign countries to the clause at 252.245-7004; Modified language at 252.245-7004(h)(2) to allow the plant clearance (printed page 52142) officer discretion in requiring scrap warranties; Added clarifying language at 252.245-7004(j)(9)(i) on verification of demilitarization actions by Government representatives, including use of DRMS Form 145 or equivalent; and Renumbered the DFARS text and clauses, as necessary. III. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563

emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is a significant regulatory action and, therefore, was subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804. IV. Regulatory Flexibility Act DoD certifies that this final rule will not have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601, et seq., because this final rule imposes no new requirements on small entities. The rule revises DFARS part 245, Government Property, to reflect the recent revisions to FAR part 45, Government Property. It makes no significant change to DoD policy for the management of Government property in the possession of contractors. No comments were received on the expected impact of this rule on small entities in response to publication of the proposed rule. V. Paperwork Reduction Act

The NIST Risk Management Framework (RMF), described in NIST Special Publication 800-37 Revision 1, Guide for Applying the Risk Management Framework to Federal Information Systems: a Security Life Cycle Approach, is a methodology for implementing risk management at the information systems tier. The RMF (depicted in Figure 2) identifies six distinct steps that provide a disciplined and structured process to integrate information security risk management activities into the system development life cycle. The RMF addresses security concerns of organizations related to the design, development, implementation, operation, and disposal of information systems and the environments in which those systems operate. The criteria for whether a security control is assurance- or functionality-related is based on the overall characteristics of the control. In general, assurance-related controls are controls that: (i) define processes, procedures, techniques, or methodologies for designing and developing information systems and system components; (ii) provide supporting operational processes including improving the quality of systems, components, or processes; (iii) produce security evidence from developmental or operational activities; (iv) determine security control effectiveness or risk; or (v) improve personnel skills, expertise, and understanding. Many organizations use well-known international information security standards as the basis or as a supplemental source of security controls for risk management. To aid in selection and comparison, SP 800-53 Rev. 4 provides mapping tables to provide organizations with a general indication of security control coverage with respect to ISO/IEC 27001, Information technology Security techniques-- Information security management systems--Requirements and ISO/IEC 15408, Information technology -- Security techniques -- Evaluation criteria for IT security.

3.2.5 Develop Recommendations ... 3.2.5 Develop Recommendations This step results in a plan of action to address recommended implementation approaches. 3.2.5.

Accordingly, the White House has directed Federal agencies to take specific steps to mitigate the threat of [cryptanalytically relevant quantum computers] through a timely and equitable transition of the Nation's cryptographic systems to interoperable quantum-resistant cryptography. [888] NCVHS examined these security issues and provided recommendations to the Department for applying the safeguards of the HIPAA Rules to potential quantum computing threats. Specifically, NCVHS declared that incorporation of recent Administration guidance for Federal agencies on vulnerable cryptographic systems is necessary to strengthen the Technical Safeguards within the Security Rule. [889] This joint guidance, developed by NIST, CISA, and NSA, encourages the early planning for migration to post-quantum cryptographic standards by developing a Quantum-Readiness Road map. [890] It also recommends that organizations prepare a cryptographic inventory, discuss post-quantum roadmaps with technology vendors, consider their supply chain's readiness for quantum computing, and consider the responsibilities of their technology vendors with respect to preparing for quantum readiness. [891] The Department encourages regulated entities to incorporate these activities as part of their ongoing risk management programs. For example, the steps presented in the joint guidance--surveying the environment for potential risks and vulnerabilities that endanger ePHI, identifying workforce members with responsibility for addressing them, inventorying quantum-vulnerable systems, including that inventory in its risk analysis and risk management, and working with technology vendors to ensure their readiness--are all activities that already are required by the administrative safeguards of the Security Rule.

ton-Micali Signature (LMS) system [2] and the eXtended Merkle Signature Scheme (XMSS) [1], along with their multi-tree variants, the Hierarchical Signature System (HSS) and multi-tree XMSS (XMSS MT). All of the digital signature schemes specified in FIPS 186 will be broken if largescale quantum computers are ever built. The security of the stateful HBS schemes in this publication depends only

on the security of the underlying hash functions-in particular, the infeasibility of finding a preimage or a second preimage-and it is believed that the security of hash functions will not be broken by the development of large-scale quantum computers [20].

Executive Order (EO) 14028, 'Improving the Nation's Cybersecurity,' tasks the National Institute of Standards and Technology (NIST), in coordination with the Federal Trade Commission (FTC) and other agencies, to initiate pilot programs for cybersecurity labeling. NIST is, among other actions, directed ' to identify IoT cybersecurity criteria for a consumer labeling program.' This document seeks to fulfill this directive by recommending consumer IoT product label criteria, label design and consumer education considerations, and conformity assessment considerations for use by a scheme owner to inform a consumer Internet of Things (IoT) product labeling program. | Introduction

.....

.1 | Introduction

.....1 | Introduction

.....1 | |-----

-----|-----

-----|-----

-----| | 1.1 | Background.....

.....

(f) NIST SP 800-82, revision 2, titled 'Guide to Industrial Control Systems (ICS) Security' provides guidance on how to secure ICS, including Supervisory Control and Data Acquisition (SCADA) systems, Distributed Control Systems (DCS), and other control system configurations such as Programmable Logic Controllers (PLC), while addressing their unique performance, reliability, and safety requirements. The document provides an overview of ICS and typical system topologies, identifies typical threats and vulnerabilities to these systems, and provides recommended security countermeasures to mitigate the associated risks. This document is incorporated by reference as a source for definitions. (g) NIST SP 800-115, titled 'Technical Guide to Information Security Testing and Assessment' assists organizations in planning and conducting technical information security tests and examinations, analyzing findings, and developing mitigation strategies. The guide provides practical recommendations for designing, implementing, and maintaining technical information security test and examination processes and procedures. These can be used for several purposes, such as finding vulnerabilities in a system or network and verifying compliance with a policy or other requirements. The guide is not intended to present a comprehensive information security testing and examination program but rather an overview of key elements of technical security testing and examination, with an emphasis on specific technical techniques, the benefits and limitations of each, and recommendations for their use. This document is incorporated by reference as a source for definitions. (h) NIST SP 800-160, Volume 2, revision 1, titled 'Developing Cyber-Resilient Systems: A Systems Security Engineering Approach' focuses on cyber resiliency engineering-an emerging specialty systems engineering discipline applied in conjunction with systems security engineering and resilience engineering to develop survivable, trustworthy secure systems. Cyber resiliency engineering intends to architect, design, develop, implement, maintain, and sustain the trustworthiness of systems with the capability to anticipate, withstand, recover from, and adapt to adverse conditions, stresses, attacks, or compromises that use or are enabled by cyber resources. From a risk management perspective, cyber resiliency is intended to help reduce the mission, business, organizational, enterprise, or sector risk of depending on cyber resources. This document is incorporated by reference as a source for definitions.

For the final rule, FDA has changed the record retention requirements in § 1.360(b) to require record retention by nontransporters for: (1) 6 months for food for which a significant risk of spoilage, loss of value, or loss of palatability occurs within 60 days after the date you receive or release the food; (2) 1 year for food for which a significant risk of spoilage, loss of value, or loss of palatability occurs only after a minimum of 60 days, but within 6 months, after the date you receive or release the food; and (3) 2 years for food for which a significant risk of spoilage, loss of value, or loss of palatability does not occur sooner than 6 months after the date you receive or release the food, including foods preserved by freezing, dehydrating, or being placed in a hermetically sealed container. Transporters or nontransporters retaining records on behalf of a transporter are required to retain 6 months records for food having a significant risk of spoilage, loss of value, (printed page 71605) or loss of palatability within 60 days after the date the

food is received or released and 1 year all food having a significant risk of spoilage, loss of value, or loss of palatability after a minimum of 60 days after the date the food is received or released. FDA chose this approach because: (1) The food industry already is familiar with classification of foods into these three categories due to existing regulations and practices and (2) it will mitigate the problem raised by some comments of inadequate infrastructure for long term storage of records for the shorter shelf life foods. FDA believes that a tracing investigation involving food for which a significant risk of spoilage or significant loss of value occurs within 60 days under normal shipping and storage conditions will not be compromised by providing for the reduced record retention of 6 months because most of these tracebacks are initiated within 6 months of the outbreak. In addition, FDA has excluded the distribution of food directly to consumers from the requirement to keep records of immediate subsequent recipients of food because FDA can obtain information from consumers and notify them when necessary. Often, consumer illness is the first common indicator that food may be adulterated and present a threat of serious adverse health consequences or death. Requiring retailers to retain records for only weeks or months would greatly impede FDA's ability to conduct a rapid and effective traceback. FDA has selected those timeframes for record retention based on the amount of time perishable and nonperishable food may remain in commerce, and thus, may be the subject of a traceback investigation. FDA further notes its understanding that many retailers currently maintain records for 2 years.

(2) Prescribes requirements, restrictions, and other safeguards to prevent unauthorized disclosure of classified information and protect special classes of classified information. (3) Prescribes that contractors will implement the provisions of this rule no later than 6 months from the effective date of this rule. § 117.2 Applicability. (a) This rule applies to: (1) The Office of the Secretary of Defense, the Military Departments, the Office of the Chairman of the Joint Chiefs of Staff and the Joint Staff, the Combatant Commands, the Office of the Inspector General of the Department of Defense, the Defense Agencies, the DoD Field Activities, and all other organizational entities within the DoD (referred to collectively in this rule as the 'DoD Components'). (2) All executive branch departments and agencies. (3) All industrial, educational, commercial, or other non-USG entities granted access to classified information by the USG executive branch departments and agencies or by foreign governments. (4) The release of classified information by the USG to contractors, who are required to safeguard classified information released during all phases of the contracting, agreement (including cooperative research and development agreements), licensing, and grant processes, i.e., the preparation and submission of bids and proposals, negotiation, award, performance, and termination. Also, it applies in situations involving a contract, agreement, license, or grant when actual knowledge of classified information is not required, but reasonable physical security measures cannot be employed to prevent aural or visual access to classified information, because there is the ability and opportunity to gain knowledge of classified information. It also applies to any other situation in which classified information or FGI that is furnished to a contractor requires protection in the interest of national security, but which is not released under a contract, license, certificate or grant. (b) This rule does not: (1) Limit in any manner the authority of USG executive branch departments and agencies to grant access to classified information under the cognizance of their department or agency to any individual designated by them. The granting of such access is outside the scope of the NISP and is accomplished pursuant to E.O. 12968, E.O. 13526, E.O. 13691, the AEA, and applicable disclosure policies. (2) Apply to criminal proceedings in the courts or authorize contractors or their employees to disclose classified information in connection with any criminal proceedings. Defendants and their representative in criminal proceedings in U.S. District Courts, Courts of Appeal, and the U.S. Supreme Court may gain access to classified information in accordance with 18 U.S.C. Appendix 3, Section 1, also known as and referred to in this rule as the 'Classified Information Procedures Act,' as amended. § 117.3 Acronyms and Definitions.

Portions of this system of records that fall within the provisions of 5 U.S.C. 552a(k)(5) may be exempt from the following subsections (d)(1) through (d)(5). (ii) Authority. 5 U.S.C. 552a(k)(5). (iii) Reasons. From subsections (d)(1) through (d)(5) because the agency is required to protect the confidentiality of sources who furnished information to the Government under an expressed promise of confidentiality or, prior to September 27, 1975, under an implied promise that the identity of the source (printed page 14804) would be held in confidence. This confidentiality is needed to maintain the Government's continued access to information from persons who otherwise might refuse to give it. This exemption is limited to disclosures that would reveal the identity of a confidential source. (2) System identifier and name. DWHS P28, The Office of the Secretary of

Defense Clearance File. (i) Exemption. This system of records is exempt from subsections (c)(3) and (d) of 5 U.S.C. 552a, which would require the disclosure of investigatory material compiled solely for the purpose of determining access to classified information but only to the extent that disclosure of such material would reveal the identity of a source who furnished information to the Government under an expressed promise that the identity of the source would be held in confidence or, prior to September 27, 1975, under an implied promise that the identity of the source would be held in confidence. A determination will be made at the time of the request for a record concerning the specific information which would reveal the identity of the source. (ii) Authority. 5 U.S.C. 552a(k)(5). (iii) Reasons. This exemption is required to protect the confidentiality of the sources of information compiled for the purpose of determining access to classified information. This confidentiality helps maintain the Government's continued access to information from persons who would otherwise refuse to give it. (3) System identifier and name. DGC 04, Industrial Personnel Security Clearance Case Files. (i) Exemption. All portions of this system which fall under 5 U.S.C. 552a(k)(5) are exempt from the following provisions of title 5 U.S.C. 552a: (c)(3); (d). (ii) Authority. 5 U.S.C. 552a(k)(5). (iii) Reasons.

Although this section currently addresses policies and procedures and documentation, it does not require or include standards to govern how regulated entities must implement, maintain, and document implementation of all security measures. Implementing, maintaining, and documenting implementation of all security measures is important to ensure that regulated entities make well-reasoned decisions about implementing the requirements of this rule. Just as the Department believes that it is necessary to consider expanding the definition of "security measures" to better reflect that security measures should be multi-layered, we also believe that it is necessary to consider providing a more complete instruction concerning how regulated entities must implement, maintain, and document their implementation of the required security measures. Additionally, OCR's own experience in investigations and audits leads us to believe that many regulated entities may not be documenting their security measures or their implementation of those measures. [864] It is critical for a regulated entity to commit to writing the security measures required by the Security Rule to ensure consistent implementation and compliance with the Security Rule. Verbal instructions may be forgotten or misconstrued, and what the regulated entity believes to be common knowledge may not be or may be relayed incorrectly between workforce members. Additionally, based on OCR's enforcement experience, the Department believes that regulated entities may not be periodically reviewing and updating their documentation when they modify their security measures in response to environmental or operational changes affecting the security of their ePHI. Given the constant evolution of technology and the everchanging behavior of cybercriminals in response to technological evolution, the Department believes that regular review of cybersecurity-related security measures is essential for protecting the confidentiality, integrity, and availability of ePHI and relevant electronic information systems. 3. Proposals As discussed above, the Department has proposed to revise other provisions of the Security Rule to clarify the differences between administrative and technical safeguards and between policies and procedures on the one hand and technical controls on the other hand. We have also proposed to revise other provisions of the Security Rule to clarify that a regulated entity is required to implement and maintain its administrative, physical, and technical safeguards, including its policies and procedures. These proposals clarify that such maintenance requires the review, testing, and modification of the regulated entity's security measures on a regular cadence, meaning that the regulated entity's security measures can be modified at any time. Given these proposals, the Department believes that we must also propose to revise 45 CFR 164.316

In newly redesignated paragraph (g): i. Removing the heading. ii. Removing "DIB participants" and adding in its place "DIB CS Program participants". i. Revising newly redesignated paragraphs (h) and (i). j. Removing "DIB participants" and adding in its place "DIB CS Program participants" in newly redesignated paragraph (j) introductory text. k. In newly redesignated paragraph (k): i. Removing "DIB participants" and adding in its place "DIB CS Program participants". ii. Removing "DIB participant" and adding in its place "DIB CS Program participant". l. Removing "DIB participants" and adding in its place "DIB CS Program participants" in newly redesignated paragraph (l). m. Removing "DIB participants" and adding in its place "DIB CS Program participants" in newly redesignated paragraph (m). n. In newly redesignated paragraph (n): i. Removing "DIB participant" and adding in its place "DIB CS Program participant" wherever it appears. ii. Removing "DIB participant's FA" and adding in its place "DIB CS Program participant's FA". o. In newly redesignated paragraph (o): i. Removing "DIB participant" and adding in its place "DIB CS Program

participant wherever it appears. ii. Removing paragraph (m) of this section and adding in its place paragraph (n) of this section. The revisions and addition read as follows: §-236.5 DoD's DIB CS Program. (a) All defense contractors that meet the requirements set forth in §-236.7 are eligible to join the DIB CS Program as a DIB CS Program participant. Defense contractors meeting the additional eligibility requirements in §-236.7 can elect to access and receive classified information electronically. * * * * (f) As participants of the DIB CS Program, defense contractors are encouraged to share cyber threat indicators and information that they believe are valuable in alerting the Government and other DIB CS Program participants to better counter threat actor activity. Cyber activity that is not covered under §-236.4 may be of interest to DIB CS Program participants and DoD. * * * * (h) Prior to receiving GFI, each DIB CS Program participant shall provide the requisite points of contact information, to include U.S. citizenship and security clearance information, as applicable, for the designated personnel within their company in order to facilitate the DoD-DIB interaction in the DIB CS Program. The Government will confirm the accuracy of the information provided as a condition of that point of contact being authorized to act on behalf of the DIB CS Program participant for this program. (i) GFI will be issued via both unclassified and classified means. DIB CS Program participants handling and safeguarding of classified information shall be in compliance with 32 CFR part 117. The Government shall specify transmission and distribution procedures for all GFI, and shall inform DIB CS Program participants of any revisions to previously specified transmission or procedures. * * * * §-236.6 [Amended] 8. Amend §-236.6 by: a.

Scott Rose Wireless Networks Division Communications Technology Laboratory For additional information on NIST's Cybersecurity programs, projects, and publications, visit the Computer Security Resource Center. Information on other efforts at NIST, the Information Technology Laboratory (ITL) and Communications Technology Laboratory (CTL) is also available. Zero trust related information is also found on the zero trust topic page. National Institute of Standards and Technology Attn: Wireless Networks Division, Communications Technology Laboratory 100 Bureau Drive (Mail Stop 8920) Gaithersburg, MD 20899-8920

This draft guidance refers to previously approved collections of information found in FDA regulations. These collections of information are subject to review by the Office of Management and Budget (OMB) under the Paperwork Reduction Act of 1995 (the PRA) (44 U.S.C. 3501-3520). The collections of information in 21 CFR part 807, subpart E have been approved under OMB control number 0910-0120, and the collections of information in 21 CFR part 801 and 21 CFR 809.10 have been approved under OMB control number 0910-0485. The labeling requirement listed in sections 5 and 8; Intended Use, is not subject to review under the PRA because it is a public disclosure of information originally supplied by the Federal Government to the recipient for the purpose of disclosure to the public (5 CFR 1320.3(c)(2) and 21 CFR 1040.10(g)). V. Comments Interested persons may submit to the Division of Dockets Management (see ADDRESSES) either electronic or written comments regarding this document. It is only necessary to send one set of comments. It is no longer necessary to send two copies of mailed comments. Identify comments with the docket number found in brackets in the heading of this document. Received comments may be seen in the Division of Dockets Management between 9 a.m. and 4 p.m., Monday through Friday. (printed page 69041) Dated: November 1, 2011. Leslie Kux, Acting Assistant Commissioner for Policy. [FR Doc. 2011-28725 Filed 11-4-11; 8:45 am] BILLING CODE 4160-01-P

Section 170.9 addresses the roles, responsibilities, and requirements for C3PAOs, which are the organizations that perform CMMC Level 2 certification assessments for OSCs. The C3PAOs will submit assessment data into the CMMC instantiation of government owned and operated system called eMASS, [22] a CMMC instance of the Enterprise Mission Assurance Support Service. C3PAOs issue Certificates of CMMC Status, in accordance with the requirements in §-170.17 of this part. Section 170.9 addresses detailed requirements for C3PAOs with regards to national security background checks, foreign ownership, reporting, records management, information protection, quality assurance, and appeals. The information systems used by C3PAOs to process Level 2 certification assessment information have to meet all of the security requirements for CMMC Level 2 and will be assessed by DCMA DIBCAC. C3PAOs need to comply with ISO/IEC 17020:2012(E), as well as with the Accreditation Body's policies for CoI, CoPC, and Ethics. Prior to a C3PAO being compliant with ISO/IEC 17020:2012(E), the C3PAO may be authorized but not accredited. After a C3PAO is compliant with ISO/IEC 17020:2012(E), the C3PAO may be accredited. Section 170.10-CMMC Assessor and Instructor Certification Organization (CAICO) Section 170.10 addresses the roles, responsibilities, and

requirements for the CAICO, the organization that trains, tests, designates Provisional Instructors (PIs), and certifies CMMC Certified Professionals (CCPs), CMMC Certified Assessors (CCAs), CMMC Certified Instructors (CCIs). There is only one CAICO for the DoD CMMC Program at any given time. The CAICO must comply with ISO/IEC 17024:2012(E), as well as with the Accreditation Body's policies for Col, CoPC, and Ethics. Section 170.10 addresses detailed requirements for the CAICO with regards to certification examinations, quality assurance, appeals, records management, reporting, separation of duties, and information protection. Section 170.11-CMMC Certified Assessor (CCA) Section 170.11 addresses the roles and responsibilities of a CMMC Certified Assessor (CCA) who conduct Level 2 certification assessments. In order to be a CCA, a candidate must first be a CCP, must adhere to the requirements set forth in § 170.10, § 170.8(b)(17), and complete a Tier 3 background investigation or equivalent. The required cybersecurity experience for different CCA roles is addressed in § 170.11(b)(6) and (10). Section 170.11 addresses CCA requirements with respect to security breaches; completion of a Tier 3 background investigation or equivalent; reporting; sharing assessment information; and permitted use of C3PAO equipment, devices, and services. Section 170.12-CMMC Instructor

only one or several), the ability of a regulated entity to execute the remaining implementation specification(s) depends on whether the remaining implementation specifications are dependent on one another or operate together to impose requirements on regulated entities. For example, several proposed implementation specifications under the standard for facility access controls at 45 CFR 164.310(a)(1) would require a regulated entity to both establish and implement written procedures pertaining to specific requirements such as contingency operations, facility security planning and access control and validation, and then subsequently review the written policies and procedures every 12 months. Should a court invalidate or deem inapplicable the implementation specification to establish and implement written policies procedures, the secondary specification requiring review of said procedures would also become invalid. The Department believes that each definition is independent of all other definitions. This list of examples is not intended to be exhaustive. The absence from this list of any particular provision should not be construed to mean that the Department considers that provision to be not severable from other parts of the rule. To ensure that our intent for severability of provisions is clear in the CFR, the Department proposes to add a section on severability at 45 CFR 164.320. Proposed 45 CFR 164.320 would state our intent that if any provision of this subpart is held to be invalid or unenforceable, it shall be construed to give maximum effect to the provision permitted by law unless the holding shall be one of utter invalidity or unenforceability, in which case the provision shall be severable from this subpart and shall not affect the remainder thereof or the application of the provision to other persons not similarly situated or to other dissimilar circumstances. The Department requests comment on the foregoing proposal, including any benefits, drawbacks, or unintended consequences. K. New and Emerging Technologies Request for Information Technology is constantly evolving, able to perform increasingly complex tasks, including those with the potential to improve health care and communication between individuals and care providers. These new and evolved technologies will continue to transform health care in a variety of ways, including providing regulated entities with new tools for faster and more accurate diagnoses, effective treatments, and more efficient administration. As a regulated entity considers the application of new technologies or the use of existing tools in innovative ways, it also must consider whether these technologies create, receive, maintain, or transmit ePHI, and, if so, how to secure them. The Security Rule was designed to be technology-neutral for this very reason and continues to provide the foundation for ensuring the confidentiality, integrity, and availability of all ePHI as technology changes. [877]

As stated in § 170.20(a), DoD intends to allow qualified standards acceptance of High confidence assessment using NIST SP 800-171 Rev 2 for CMMC Level 2. However, the CMMC Program requirements proposed in this rule will be implemented in the DFARS, as needed, which may result in changes to current DoD solicitation provisions and contract clauses relating to cybersecurity assessments. b. Cloud Standards Comment: Many commenters expressed concerns regarding CMMC recognition of Federal Risk and Authorization Management Program (FedRAMP) and requested guidance on which FedRAMP baselines, if any, would be granted standards acceptance at each CMMC Level. A few commenters sought assurance that DoD Cloud Computing Security Requirements Guide (SRG) Impact Levels 4 and 5 would not be applied to CMMC Level 3. Response: CMMC does not offer comprehensive acceptance of FedRAMP. The CMMC Program allows the acceptance of FedRAMP environments in some cases to meet CMMC requirements in connection with use of a Cloud Service Provider (CSP). If an OSC uses an external CSP to process, store, or transmit CUI or to provide security protection for any such component, the OSC must ensure

the CSP's product or service offering either (1) is authorized as FedRAMP Moderate or High on the FedRAMP Marketplace; or (2) meets the security requirements equivalent to those established by the Department for the FedRAMP Moderate or High baseline. The CSP will provide evidence that its product or service offering meets the security requirements equivalent to FedRAMP Moderate or High by providing a body of evidence (BOE) that attests to and describes how the CSP's product or service offering meets the FedRAMP baseline security requirements. Note that for any portion of the on-premises (internal) network (printed page 89071) that interacts with the cloud service offering and is within the CMMC Assessment Scope, the OSC is required to meet all applicable CMMC requirements to achieve certification. The DoD Cloud Computing SRG applies to DoD-provided cloud services and those provided by a contractor on behalf of the department, i.e., a commercial cloud service provider or integrator. Cloud Computing SRG does not apply to CMMC. c. Other Standards

Comment:

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 159 [Docket ID: DoD-2020-OS-0016] RIN 0790-AK87 AGENCY: Office of the Under Secretary of Defense for Acquisition and Sustainment, Department of Defense (DoD). ACTION: Final rule. SUMMARY: The DoD is finalizing updates to this rule resulting from changes from the National Defense Authorization Act (NDAA) for Fiscal Years (FY) 2017 and 2020 as well as DoD policy updates. These changes include administrative updates and clarifications to private security contractors (PSCs) performing duties while under contract to DoD in support of a contingency operations, humanitarian or peace operations, or other military operations or exercises. DATES: This rule is effective on October 11, 2022. FOR FURTHER INFORMATION CONTACT: Ms. Donna M. Livingston, 703-692-3032, donna.m.livingston.civ@mail.mil . SUPPLEMENTARY INFORMATION: Legal Authority This section of the CFR was last updated in a final rule published in the Federal Register (76 FR 49650) on August 11, 2011. DoD is finalizing this rule to meet the mandates of NDAA for FY 2017 and 2020 and updates to DoD policy that require the Department to propose additional guidance on inherently governmental functions, PSC compliance with national and international recognized quality assurance management standards, and to add new definitions for total force and arming authorities. DoD also added language requiring PSCs to cooperate with DoD on all U.S. Government investigations. Additional language is also provided to state DoD is responsible for providing the appropriate contract administration oversight of PSCs. The corresponding internal DoD policy is established in DoD Instruction 3020.50, 'Private Security Contractors (PSCs) Operating in Contingency Operations, Humanitarian or Peace Operations, or Other Military Operations or Exercises,' published on July 22, 2009, and last updated on August 31, 2018. This Instruction will be updated based on publication of this final rule. For additional information, DoD Instruction 3020.50 can be accessed at <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodi/302050p.pdf> . Discussion of Comments A proposed rule titled 'Private Security Contractors (PSCs) Operating in Contingency Operations, Humanitarian or Peace Operations, or Other Military Operations or Exercises' was published in the Federal Register (86 FR 28042) on May 25, 2021. Two commenters provided comments and the Department's responses are as follows. (printed page 55282) Comment:

(4) Nothing in the amendment process is intended or designed to permit a collateral attack upon what has already been the subject of a judicial or quasi-judicial determination. However, while the individual may not attack the accuracy of the judicial or quasi-judicial determination under this part, he or she may challenge the accuracy of the recording of that action. (printed page 14733)

(c) An individual requesting amendment or correction of records will receive a written acknowledgment of receipt of the request within 10 days (excluding Saturdays, Sundays, and legal public holidays), as required by the Privacy Act. The response to the request may be made in lieu of the acknowledgment of receipt provided the response is made within 10 days (excluding Saturdays, Sundays, and legal public holidays). The response to the request must be made promptly and indicate whether the request is granted or denied. (d) If the request for amendment or correction is granted in whole or in part, the response to the individual will receive a description or copy of the amendment or correction made and, if a copy of the amended or corrected record is not included in the response, notification of the right to obtain a copy of the corrected or amended record in disclosable form. (e) If the request for amendment or correction is denied in whole or in part, the

response to the individual will include a signed letter stating: (1) The reason(s) for the denial; and (2) The procedure for appeal of the denial under paragraph (f) of this section, including the name, position title and business address of the official who will act on the appeal. (f) An individual may appeal the denial of a request for amendment or correction to the individual's record to the appellate authority at the address listed in the notification of denial letter, in the same manner as for a denial of a request for access to records (see § 310.6). The appeal determination shall be made within 30 working days (excluding Saturdays, Sundays, and legal public holidays) from the date of the appeal, unless the period is extended for good cause. If the appeal is denied in whole or in part, the individual will be advised of the right to file a Statement of Disagreement as described in paragraph (g) of this section, and of the right under the Privacy Act for judicial review of the decision.

1. Current Provisions a. Section 164.308(a) Section 164.308(a) contains most of the standards and associated implementation specifications that are categorized as administrative safeguards. The standards for administrative safeguards are as follows: Security management process. Assigned security responsibility. Workforce security. Information access management. Security awareness and training. Security incident procedures. Contingency plan. Evaluation. The standard for security management process at 45 CFR 164.308(a)(1)(i) requires regulated entities to implement policies and procedures to prevent, detect, contain, and correct security violations. The Security Rule directs regulated entities as to how they are to comply with the standard for security management process through four implementation specifications. Section 164.308(a)(1)(ii)(A) requires regulated entities to conduct a risk analysis that accurately and thoroughly assesses potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI they hold. The implementation specification for risk management at 45 CFR 164.308(a)(1)(ii)(B) requires regulated entities to implement measures to reduce risks and vulnerabilities, such as those identified in the risk analysis, to a reasonable and appropriate level. Under 45 CFR 164.308(a)(1)(ii)(C), regulated entities are required to apply appropriate sanctions against workforce members who fail to comply with applicable security policies and procedures, while the implementation specification for information system activity review at 45 CFR 164.308(a)(1)(ii)(D) requires regulated entities to implement procedures to regularly review information system activity records. The standard for assigned security responsibility at 45 CFR 164.308(a)(2) requires regulated entities to identify a security official who is responsible for the development and implementation of the policies and procedures that are required by this section. There are no implementation specifications associated with this standard. Section 164.308(a)(3)(i) contains the standard for workforce security and requires regulated entities to implement policies and procedures to ensure that their workforce members have appropriate access to ePHI, which includes preventing workforce members who do not have authorized access from (printed page 935) obtaining it. The implementation specifications associated with this standard address the need to implement certain procedures regarding workforce member access to ePHI. Section 164.308(a)(3)(ii)(A) addresses the implementation of procedures for the authorization and/or supervision of workforce members who work with ePHI or in locations where it might be accessed. The implementation specification for workforce clearance procedure at 45 CFR 164.308(a)(3)(ii)(B) addresses the implementation of procedures to determine that a workforce member's access to ePHI is appropriate, while 45 CFR 164.308(a)(3)(ii)(C)

and follow the instructions on the site. All items submitted must cite OMB Control No. 9000-XXXX, Controlled Unclassified Information. Comments submitted in response to this rule will be made publicly available and are subject to disclosure under the Freedom of Information Act. For this reason, please do not include in your comments information of a confidential nature, such as sensitive personal information or proprietary information, or any information that you would not want publicly disclosed unless you follow the instructions below for confidential comments. Summary information of the public comments received, including any specific comments, will be posted on <https://www.regulations.gov>. All filers using the portal should use the name of the person or entity submitting comments as the name of their files, in accordance with the instructions below. Anyone submitting business confidential/proprietary information should clearly identify any business confidential/proprietary portion at the time of submission, file a statement justifying nondisclosure and referencing the specific legal authority claimed, and provide a non-confidential/non-proprietary version of the submission. Any business confidential information should be in an uploaded file that has a file name beginning with the characters ·BC·. Any page containing business confidential information must be clearly marked ·BUSINESS CONFIDENTIAL/PROPRIETARY· on the top of that page. The corresponding non-confidential/non-proprietary version of those comments must

be clearly marked ·PUBLIC·. The file name of the non-confidential version should begin with the character ·P·. The ·BC· and ·P· should be followed by the name of the person or entity submitting the comments or rebuttal comments. All filers should name their files using the name of the person or entity submitting the comments. Any submissions with file names that do not begin with a ·BC· will be assumed to be public and will be made publicly available through <https://www.regulations.gov>. To confirm receipt of your comment(s), please check <https://www.regulations.gov>, approximately two-to-three days after submission to verify posting. If there are difficulties submitting comments, contact the GSA Regulatory Secretariat Division at 202-501-4755 or GSARegSec@gsa.gov. Public comments are particularly invited on: The necessity of this collection of information for the proper performance of the functions of Federal Government acquisitions, including whether the information will have practical utility; The accuracy of the estimate of the burden of this collection of information; Ways to enhance the quality, utility, and clarity of the information to be collected; and Ways to minimize the burden of the collection of information on respondents, including the use of automated collection techniques or other forms of information technology.

(xi) All written correspondence with the USG on the export. (xii) All information relating to political contributions, fees, or commissions furnished or obtained, offered, solicited, or agreed upon, as outlined in the ITAR parts 126.16(m) or 126.17(m). (xiii) Purchase order, contract, or letter of intent. (xiv) Technical data actually exported. (xv) The internal transaction number for the electronic export information filing in the automated export system. (xvi) All shipping documentation (including, but not limited to, the airway bill, bill of lading, packing list, delivery verification, and invoice). (xvii) Statement of registration (Department of State Form DS-2032 (available at: https://www.pmddtc.state.gov/sys_attachment.do?sysparm_referring_url=tear_off&view=true&sys_id=dabc05f6db6be344529d368d7c961984)). §.117.20 Critical Nuclear Weapon Design Information (CNWDI). (a) General. This section contains the special requirements for protection of CNWDI. The sensitivity of DoD CNWDI is such that access shall be granted to the absolute minimum number of employees who require it for the accomplishment of assigned responsibilities on a classified contract. Because of the importance of such information, special requirements have been established for its control. DoDI 5210.02, ·Access to and Dissemination of Restricted Data and Formerly Restricted Data· (available at: <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodi/521002p.pdf?ver=2019-01-14-072742-700>) establishes these controls in the DoD. (b) Briefings. Prior to having access to CNWDI, employees will be briefed on its sensitivity by the FSO or his or her alternate. The FSO will be initially briefed by a USG representative. (1) The briefing will include: (i) The definition of CNWDI. (ii) A reminder of the extreme sensitivity of the information. (iii) An explanation of the individual's continuing responsibility for properly safeguarding CNWDI and for ensuring that dissemination is strictly limited to other personnel who have been authorized for access and have a need-to-know for the particular information. (2) The briefing will also be tailored to cover any special local requirements. Upon termination of access to CNWDI, the employee will be given an oral debriefing. (c) Markings. In addition to any other required markings, CNWDI material will be clearly marked in accordance with DoDI 5210.02. At a minimum, CNWDI documents will show such markings on the cover or first page. Portions of documents that contain CNWDI will be marked with an (N) or (CNWDI) following the classification of the portion; for example, TS (RD)(N) or TS(RD)(CNWDI). (d) Subcontractors. Contractors will not disclose CNWDI to subcontractors without the prior written approval of the GCA. This approval may be included in a contract security classification specification, or equivalent, other contract-related document, or by separate correspondence. (e) Transmission outside the facility.

CUI handling is governed by 32 CFR Part 2002 and the ISOO CUI Marking Handbook (Version 1.1). Organizations must implement NIST SP 800-171 controls to protect CUI and follow marking requirements: - Banner markings (CUI designation at top and bottom of pages/documents) - Portion markings (optional, marking individual sections with (CUI)) - Dissemination controls where applicable - Proper handling, storage, and destruction procedures For specific marking guidance, consult the ISOO CUI Marking Handbook and your organization's CUI handling procedures. Under DFARS 252.204-7012, any incident involving potential CUI compromise must be reported to DC3 within 72 hours.

- Create clear standards and guidelines from a cybersecurity and privacy perspective for IoT device manufacturers and solution providers. - Certification and labeling programs are emerging for both

devices and overall solutions. - Data standards, integration, and communication protocols can help facilitate ecosystem compatibility to ensure devices can communicate. - Dependable supply chains are important. - Clear and consistent standards increase device interoperability and decrease cost. - Providing direction on 'mandatory' requirements would benefit manufacturers. - Educating the workforce and/or future workforce for the digital transformation of the economy, such as developing training initiatives to increase skilled resources to implement and maintain IoT solutions. - Public and private partnerships strengthen IoT security by leveraging the strengths, knowledge, and resources from both industry and government. When discussing IoT cybersecurity, the participants frequently returned to the challenge of the varying information and visibility available to different roles across the IoT ecosystem. Manufacturers are best positioned to understand the cybersecurity capabilities of their IoT products including the cybersecurity capabilities of components from across the supply chain that are used to create the IoT product. Customers have highly varying cybersecurity knowledge depending on a number of factors such as whether they are a home consumer, small business, or large enterprise. Participants noted that additional roles are often needed in heterogeneous systems where components from various manufacturers must function securely together. System integrators, brand owners, retailers and other specialized support services can be mediators between the manufacturer and customer. These discussions also emphasized the role of third-party platform providers.

paragraph (b)(1) to provide that regulated entities are to apply reasonable and appropriate security measures to implement the standards and implementation specifications of the Security Rule. This proposal, if adopted, would replace the existing paragraph providing for regulated entities' reasonable and appropriate implementation of standards and implementation specifications, which could be misinterpreted to mean that a regulated entity may determine that implementation itself is unreasonable or inappropriate in some circumstances. That has never been the case. Thus, the proposed modification would clarify that implementation is not optional based on whether a regulated entity believes it is reasonable and appropriate; to the contrary, a regulated entity is required to implement the standards and implementation specifications and must adopt reasonable and appropriate security measures that allow the entity to achieve such implementation. The proposed clarification would comport more precisely with the statute, which requires regulated entities to maintain 'reasonable and appropriate' safeguards. [425] The Department also proposes to add a new element to the list of factors that regulated entities must take into account when deciding whether a particular security measure (e.g., a technical control) is reasonable and appropriate for implementing a standard and its associated implementation specifications: the effectiveness of the security measure in supporting the resiliency of the regulated entity. A regulated entity would be required to consider this factor, in addition to the existing factors, for example, when choosing a specific encryption solution that allows the entity to meet the proposed requirement to encrypt ePHI, which will help prevent an unauthorized user from accessing the entity's ePHI; or when developing its security incident plan or disaster recovery plan, which will help ensure that the regulated entity can recover data or reestablish data integrity after a security incident or disaster. The Department proposes at 45 CFR 164.306(b)(2)(v) to require a regulated entity to take into account how effectively its application of a particular security measure to achieve compliance with a standard and its associated implementation specifications would support its resiliency in the face of an event that adversely affects the entity. According to NIST, 'information system resilience' addresses how well information systems 'continue to (i) operate under adverse conditions or stress, even if in a degraded or debilitated state, while maintaining essential operational capabilities; and (ii) recover to an effective operational posture in a time frame consistent with mission needs.' [426] Recently, in this era of rising cybercrime, NIST described 'cyber resiliency' as 'the ability to anticipate, withstand, recover from, and adapt to adverse conditions, stresses, attacks, or compromises on systems that use or are enabled by cyber resources.' [427]

32 CFR part 170 CMMC Program rule, which outlines program requirements rather than contracting procedures. This rule has no disproportionate impact on Native American owned businesses. Once identified as a requirement, the CMMC Program requirements will apply uniformly to all prospective contractors. DoD must enforce safeguarding requirements uniformly across the DIB for all contractors and subcontractors who process, store, or transmit CUI. The value of information and impact of its loss does not diminish when the information moves to DoD contractors and DoD subcontractors, regardless of their status as Native American or small disadvantaged businesses. The purpose of the CMMC Program is to ensure that DoD contracts that require contractors to

safeguard FCI and CUI (i.e., contracts that include FAR clause 52.204-21 and DFARS clause 252.204-7012) will be awarded to contractors with the ability to protect that information appropriately. Accordingly, all contractor owned information systems that process, store, or transmit FCI or CUI in the performance of a contract are subject to the requirements of FAR clause 52.204-21 and NIST SP 800-171 as implemented by DFARS clause 252.204-7012. The CMMC Program rule does not include threatened penalties. If a requirement of a DoD contract is not met, then standard contractual remedies applicable to that contract may apply. The phased implementation plan described in § 170.3(e) is intended to address ramp-up issues, provide time to train the necessary number of assessors, and allow companies the time needed to understand and implement CMMC requirements. The self-assessment requirements build on the existing DFARS clause 252.204-7020 requirement as part of basic safeguarding of CUI. CMMC Level 3 requires advanced implementation, and the phase-in period provides additional time for an OSC to achieve the higher standard. 11. Flow down. Commenters expressed concern that the CMMC rule language was not clear enough regarding when self-assessments are allowed. One commenter believed requiring prime contractors to validate the compliance of those they transmit CUI to was too onerous and that the rule language was not clear on how to determine what level of CUI is being passed. DoD Response: DoD policies guide Program Managers to appropriately apply CMMC Status requirements in DoD solicitations and resulting contracts, to include when Level 2 self-assessment rather than Level 2 certification assessment is appropriate. The commenter misinterprets the text of § 170.23, which states: If a subcontractor will process, store, or transmit CUI in performance of the subcontract and the associated prime contractor has a requirement for a CMMC Status of Level 2 (C3PAO), then the CMMC Status of Level 2 (C3PAO) is the minimum requirement for the subcontractor.

The term 'Top Secret' is an example of a classification that is appropriate for the defense community. The term 'Company Proprietary' is appropriate for commercial users. Words such as 'accounting' and 'personnel' are good examples of commercial compartments, whereas 'nato' and 'crypto' are examples of compartments related to defense. due to the widely varying needs of widely disparate interest groups. The categorization, marking, protection required and personnel clearances required differ wildly from firm to firm and nation to nation, if in fact a formal policy exists at all. This contrasts to the extremely stable, well defined world of classified information with a very small, universally recognized set of levels of hierarchical sensitivities. Given the nature of the realm of unclassified but sensitive information, it may be assumed that modelling such a policy to conform with frameworks developed for the classified realm will be problematic, if even possible.

- 2.2.4 The addition of designated information caused additional changes in more than just document marking and storage. Personnel clearances were affected as the rationale for requiring a security clearance changed. The former practice of requiring a security clearance had to be limited to only those requiring access, on a regular basis, to classified information. There was no longer as many positions requiring clearances since there was no longer the vast numbers of employees with a "need to know" requirement for classified information. This was perceived as a cost saving measure, since it would reduce the number of security clearance investigations required to be conducted by security staffs.

- 2.2.5 A requirement existed, however, to establish a level of trust for employees who did not require access to classified information but had access to designated information and valuable assets. Personnel screening was established at two levels.

One commenter has misinterpreted the answer to a public comment on a previous version of the rule, which responded to the initial CMMC Program requirements. Specialized Assets are not evaluated at Level 1. Specialized Assets at Level 2 need to be documented in the SSP and included in the asset inventory and network diagrams. They also are to be managed using the contractor's risk-based security policies, procedures, and practices. At Level 2, Specialized Assets do not need to be assessed against other CMMC security requirements. At Level 3, Specialized Assets should be prepared to be assessed against CMMC security requirements. CMMC also provides for the use of intermediary devices to safeguard OT and IOT devices that otherwise would be difficult or expensive to protect. The phrase 'or information systems not logically or physically isolated from all such systems' only appears in answers to public comments on the original 48 CFR CMMC interim final rule publication, therefore the inclusion of the phrase is not relevant to the rule. Specialized Assets span a broad spectrum of components and have different limitations on the application of security controls. Processes and practices to implement and assess security requirements on these devices are outside the scope of the CMMC rule. The Level 3 assessment is designed to provide additional safeguards to protect the most sensitive CUI against advanced persistent threats (APTs). DoD estimates that only one percent of defense contractors will require a CMMC Level 3 assessment. DoD has judged that the

risks associated with the exposure of this CUI are sufficient to justify the increased cost of a Level 3 assessment on the small percentage of the DIB that is processing, storing, or transmitting this type of data. CMMC also provides for the use of intermediary devices to safeguard OT and IOT devices that otherwise would be difficult or expensive to protect. This difference between how a Specialized Asset is assessed at Level 2 and Level 3 is risk-based and affords a reduction in cost for a Level 2 certification. The CMMC Assessment Scope for a CMMC Level 2 certification assessment is discussed between the OSC and the C3PAO. If the OSC has a goal to undergo a CMMC Level 3 certification assessment for the same assessment scope, it may be good business practice for the OSC to disclose this information to the C3PAO and be assessed based on the Level 3 scoping, however this is not required. e. Intermediary Devices Comment: One comment asks for additional information on intermediary devices as referenced in table 5 to § 170.19(d)(1). Another comment asks for direction in situations where the comment asserts intermediary devices are not practical. Response:

means any contract entered into by a contractor to furnish supplies or services for performance of a prime contract or a subcontract. It includes a contract, subcontract, purchase order, lease agreement, service agreement, request for quotation (RFQ), request for proposal (RFP), invitation for bid (IFB), or other agreement or procurement action between contractors that requires or will require access to classified information to fulfill the performance requirements of a prime contract. Subcontractor means a supplier, distributor, vendor, or firm that enters into a contract with a prime contractor to furnish supplies or services to or for the prime contractor or another subcontractor. For the purposes of this rule, each subcontractor will be considered as a prime contractor in relation to its subcontractors. Subsidiary means an entity in which another entity owns at least a majority of its voting securities. System software means computer programs that control, monitor, or facilitate use of the information system; for example, operating systems, programming languages, communication, input-output controls, sorts, security packages, and other utility-type programs. Also includes off-the-shelf application packages obtained from manufacturers and commercial vendors, such as for word processing, spreadsheets, data base management, graphics, and computer-aided design. Technical data means: (1) Information, other than software, which is required for the design, development, production, manufacture, assembly, operation, repair, testing, maintenance or modification of defense articles. This includes information in the form of blueprints, drawings, photographs, plans, instructions or documentation. (2) Classified information relating to defense articles and defense services on the U.S. Munitions List and 600-series items controlled by the Commerce Control List. (3) Information covered by an invention secrecy order. (4) Software directly related to defense articles. TFNI means classified information concerning the nuclear energy programs of other nations (including subnational entities) removed from the RD category under section 142(e) of the AEA after the DOE and the Director of National Intelligence jointly determine that it is necessary to carry out intelligence-related activities under the provisions of the National Security Act of 1947, as amended, and that it can be adequately safeguarded as NSI instead. This includes information removed from the RD category by past joint determinations between DOE and the CIA. TFNI does not include information transferred to the United States under an Agreement for Cooperation under the Atomic Energy Act or any other agreement or treaty in which the United States agrees to protect classified information. TOP SECRET

An ESP that is not an CSP and processes, stores, or transmits CUI, is considered an extension of the OSA's environment and the ESP services used to meet OSA requirements are within the scope of the OSA's CMMC assessment. As part of that environment, the ESP will be assessed against all applicable requirements and accountable for all users who have access to CUI as part of the ESP's service, not just OSA employees. ESPs that are not CSPs and do NOT process, store, or transmit CUI, do not require CMMC assessment. Nothing in the rule precludes an ESP, that is not a CSP, from voluntarily requesting a C3PAO assessment, and a C3PAO from performing such an assessment, if the ESP makes that business decision. Similarly, the ESP can request a Level 3 certification assessment from the DCMA DIBCAC if they have successfully met all the requirements during a Level 2 certification assessment. ESPs can be part of the same corporate/organizational structure but still be external to the OSA such as a centralized SOC or NOC which supports multiple business units. An ESP that is used as staff augmentation and the OSA provides all processes, technology, and facilities does not need a CMMC assessment. An ESP (not a CSP) that provides technical support services to its clients would be considered an MSP, since it does not host its own cloud platform (printed page 83200) offering. An ESP may utilize cloud offerings to deliver services to clients without being a CSP. An ESP that manages a third-party cloud service on behalf of an OSA would not be considered a CSP. 6. POA&M. Commenters expressed concern regarding the limited nature of POA&Ms in CMMC as well as the

timeline and lack of flexibility in remediating the POA&Ms. DoD Response. The DoD did not accept the recommendation to change the criteria in § 170.21 for POA&M requirements or the timeline allowed to remediate open POA&M items. The 180-day timeline and the determination of which weighted practices can be placed on a POA&M were risk-based decisions. The determination factored into account for the relative risk DoD is willing to accept when a particular practice is not met and the amount of risk the DoD is willing to accept for those security practices that remain ·NOT MET· for the extended period of time. The phased implementation plan in § 170.3(e) is intended to address ramp-up issues, provide time to train the necessary number of assessors, and allow companies the time needed to understand and implement CMMC requirements. DoD has updated the rule to add an additional six months to the Phase 1 timeline, now one year. Phase 2 will start one calendar year after the start of Phase 1. 7. Incorporation by Reference. Commenters expressed concern about the confusion between the NIST 800-171 R2 being included in the CMMC rule and not the recently published Rev 3. DoD Response. The Office of the Federal Register regulations (1 CFR part 51

) 800-125, Guide to Security for Full Virtualization Technologies , National Institute of Standards and Technology, Gaithersburg, Maryland, January 2011, 35pp. <https://doi.org/10.6028/NIST.SP.800-125>. - [2] Docker, <https://www.docker.com/> - [3] rkt, <https://coreos.com/rkt/> - [4] CoreOS Container Linux, <https://coreos.com/os/docs/latest> - [5] Project Atomic, <http://www.projectatomic.io> - [6] Google Container-Optimized OS, <https://cloud.google.com/container-optimized-dos/docs/> - [7] Open Container Initiative Daemon (OCID), <https://github.com/kubernetesincubator/cri-o> - [8] Jenkins, <https://jenkins.io> - [9] TeamCity, <https://www.jetbrains.com/teamcity/> - [10] Amazon EC2 Container Registry (ECR), <https://aws.amazon.com/ecr/> - [11] Docker Hub, <https://hub.docker.com/> - [12] Docker Trusted Registry, <https://hub.docker.com/r/docker/dtr/> - [13] Quay Container Registry, <https://quay.io> - [14] Kubernetes, <https://kubernetes.io/> - [15] Apache Mesos, <http://mesos.apache.org/> - [16] Docker Swarm, <https://github.com/docker/swarm> - [17] NIST Special Publication (SP) 800-154, Guide to Data-Centric System Threat Modeling (Draft) , National Institute of Standards and Technology, Gaithersburg, Maryland, March 2016, 25pp. <https://csrc.nist.gov/publications/detail/sp/800154/draft>. - [18] Common Vulnerability Scoring System v3.0: Specification Document , Forum for Incident Response and Security Teams (FIRST). <https://www.first.org/cvss/specification-document>. - [19] NIST Special Publication (SP) 800-111, Guide to Storage Encryption Technologies for End User Devices, National Institute of Standards and Technology, Gaithersburg, Maryland, November 2007, 40pp. <https://doi.org/10.6028/NIST.SP.800-111>. - [20] CIS Docker Benchmark, Center for Internet Security (CIS). <https://www.cisecurity.org/benchmark/docker/>. - [21] Security Enhanced Linux (SELinux), https://selinuxproject.org/page/Main_Page - [22] AppArmor, http://wiki.apparmor.net/index.php/Main_Page

3.3.3 Industry-recognized Certifications ## Focus Groups In an open-ended question, participants were asked what, if any, industry-recognized certifications they held (Figure 16). 3.3.3).

Numerous respondents commented that the estimates by DoD of the costs and economic impact of this rule are inadequate. One of these respondents commented that the rule creates costs beyond the supply chain risk management a responsible company would undertake in the course of ordinary business. Further, the scope of application of the interim rule, which requires compliance at all levels of the DoD supply chain, would require significant, costly, additional investments in supplier management and compliance mechanisms by industry. Another respondent suggested that absent a public comment period before implementation of the rule, industry has no opportunity to provide input regarding the costs and benefits of the approach DoD has taken. One respondent commented that the cumulative economic effect of the exclusion of any one company from any one contract would result in reductions in both Government and commercial business, and the loss of employment at the excluded company and the corresponding loss of payroll. Other losses would be incurred as a result of the ripple effect on primes, subcontractors, or suppliers to the excluded company, which will lose that source of supply and must then incur the expense of identifying and vetting new sources. One respondent commented that by not advising what standard DoD will use to evaluate supply chain risks, the interim rule is likely to increase the time and cost of pursuing and performing Government contracts. Response: DoD does not expect the rule to have a significant economic impact on a substantial number of entities. Companies have an existing interest in having a supply chain that they can rely on to provide it with material and supplies that allow the contractor to ultimately supply its customers with products that are safe and that do not impose threats or risks to Government information systems. The rule does not require contractors to deploy additional supply

chain risk protections. Section 806 authority applies to a specific contract, task order, or delivery order only. b. Small Business Comment: One respondent commented that the rule will drive up costs for smaller businesses by requiring significant increase in investments in compliance. Another respondent commented that the rule could prompt prime contractors to exclude new or small businesses in order to improve the evaluation of their supply chain risk profile. Response: The rule does not require contractors to deploy additional supply chain risk protections. c. Barriers to the Federal Market Comment: Two respondents commented that the rule creates significant new barriers to the Federal market, further suggesting that the interim regulation poses significant burdens for existing companies in the market and will only further dissuade new and innovative companies from entering the market. Response:

Report of the Workshop on Cryptography in Support of Computer Security ## REPORT OF THE WORKSHOP ON CRYPTOGRAPHY IN SUPPORT OF COMPUTER SECURITY Report of the Workshop on Cryptography in Support of Computer Security

During the course of assessment, DCMA DIBCAC will focus on assessing compliance with all 24 selected requirements derived from NIST SP 800-172 Feb2021, but limited checks may be performed on the 110 requirements from NIST SP 800-171 R2. If DCMA DIBCAC identifies that all 24 requirements from NIST SP 800-172 Feb2021 are satisfied, the OSA will have achieved a CMMC Status of Final Level 3 (DIBCAC) and is eligible for contract award as long as all other contractual requirements are met. Not all requirements must immediately be MET to be eligible for contract award. If the minimum score is achieved on the assessment (equal to 80% of the maximum score of 24) and certain critical requirements are met, OSAs will achieve a CMMC Status of Conditional Level 3 (DIBCAC), and all NOT MET requirements must be noted in a POA&M. At this point the OSA will have satisfied the CMMC requirements needed for contract award. OSAs must have met all 24 selected security requirements of NIST SP 800-172 Feb2021 within 180 days of receiving their Conditional CMMC Status, which must be verified with a POA&M closeout assessment by DCMA DIBCAC. If the POA&M closeout assessment finds that all requirements have been met, then the OSA will achieve a CMMC Status of Final Level 3 (DIBCAC). However, if a POA&M closeout assessment does not find that all requirements have been met by the end of 180 days, then the CMMC Status of Conditional Level 3 (DIBCAC) will expire. At this point, standard contractual remedies will apply. The OSA should submit an affirmation into SPRS after achieving a CMMC Status of Conditional Level 3 (DIBCAC) if applicable and once a CMMC Status of Final Level 3 (DIBCAC) is achieved. Being eligible for contracts subject to CMMC Level 3 (DIBCAC) also indicates eligibility for contracts subject to Level 1 (Self), Level 2 (Self), and Level 2 (C3PAO), assuming all other contractual requirements are met. To maintain CMMC Level 3 (DIBCAC) status, an OSA must undergo both a Level 2 certification assessment and a Level 3 certification assessment every three years and separately affirm compliance with Level 2 and Level 3 requirements in SPRS annually. These deadlines are based on the CMMC Status Date of the Conditional certification if applicable or the CMMC Status Date of the Final determination. CMMC Status Date is not based on the date of a POA&M closeout assessment. Flow-Down If the OSA employs subcontractors to fulfill the contract, those subcontractors must also have a minimum CMMC Status as shown in table 2. Table 2-Minimum Flow-Down Requirements Prime contractor requirement Minimum subcontractor requirement If the subcontractor will process, store, or transmit FCI CUI Level 1 (Self) Level 1 (Self) N/A. Level 2 (Self) Level 1 (Self) Level 2 (Self). Level 2 (C3PAO) Level 1 (Self) Level 2 (C3PAO). Level 3 (DIBCAC) Level 1 (Self) Level 2 (C3PAO). (printed page 83097) Summary of Provisions Contained in This Rule Section 170.1-Purpose

- Ubiquitous access: users want access to applications from multiple client devices (e.g., browsers, mobile devices). - Scalability: applications must be highly scalable to maintain availability in the face of an increasing number of users and/or increased rate of usage from the existing user base. - Agile development: organizations want frequent updates to quickly respond to organizational (process and structural) changes and market demands. Publish-Subscribe : This pattern is used when microservices need to collaborate for the realization of a complex business process or transaction. This is also called a business domain event-driven approach or domain event subscription approach. In this pattern, a microservice registers itself or subscribes to business domain events (e.g., interested in specific information or being able to handle certain requests), which are published to a message broker through an eventbus interface. These microservices are built using event-driven APIs and use asynchronous messaging protocols, such as Message Queuing Telemetry Transport (MQTT), Advanced Message Queuing Protocol (AMQP), and Kafka Messaging, which enable support for notifications and subscriptions. In asynchronous protocols, the message sender does not typically

uirements. When deciding whether to require and implement C-SCRM practices and controls, acquirers should consider both the costs of implementing these controls and the risks of not implementing them. applicable existing data and documentation that may provide evidence | Levels | Level Name | Generic Stakeholder | Activities | |-----|-----|-----|-----|

_____|| 3 |

On August 21, 1992 and January 28, 1994, notices were published in the Federal Register (57 FR 37948 and 59 FR 4031, respectively) that a Federal Information Processing Standard for Standard Security Label for the Government Open Systems Interconnection Profile was being proposed for Federal use. The written comments submitted by interested parties and other material available to the Department relevant to this standard were reviewed by NIST. On the basis of this review, NIST recommended that the Secretary approve the standard as a Federal Information Processing Standards Publication, and prepared a detailed justification document for the Secretary's review in support of that recommendation. The detailed justification document which was presented to the Secretary is part of the public record and is available for inspection and copying in the Department's Central Reference and Records Inspection Facility, Room 6020, Herbert C. Hoover Building, 14th Street between Pennsylvania and Constitution Avenues NW., Washington, DC 20230. This FIPS contains two sections: (1) An announcement section, which provides information concerning the applicability, implementation, and maintenance of the standard; and (2) a specifications section which deals with the technical requirements of the standard. Only the announcement section of the standard is provided in this notice.

(Response) ·Holding· means storage of food. Holding facilities include warehouses, cold storage facilities, storage silos, grain elevators, and liquid storage tanks. The recordkeeping requirements in §§ 1.337 and 1.345 of this final rule apply to persons who ·hold· food for purposes other than transportation. As defined in § 1.328 of this final rule, a ·transporter· is: * * * a person who has possession, custody, or control of an article of food in the United States for the sole purpose of transporting the food, whether by road, rail, water, or air. Transporter also includes a foreign person that transports food in the United States, regardless of whether that person has possession, custody, or control of that food for the sole purpose of transporting the food.* * * Truck terminals or similar facilities that are part of the transportation process and merely provide a location for trucks to transfer possession, custody, or control to another entity are not subject to the requirements in §§ 1.337 and 1.345 of the final rule, unless possession, custody, or control is transferred to that terminal or facility. (Comment 21) One comment seeks clarification on whether a ·customer,· such as an office complex, would be required to maintain records if it receives and stores a food, such as bottled water, in the customer's own storage area for subsequent distribution to the various offices within the complex. The comment also asks whether, for bottled water, such a customer would also be the immediate previous source for bottles that are returned to the bottler for reuse. (Response) FDA has added an exclusion to the final rule for persons who receive or hold food on behalf of specific individual consumers and who are not also parties to the transaction and who are not in the business of distributing food. This exclusion covers person such as a hotel concierge, the reception desk in an apartment building, and an office complex that (printed page 71571) receives bottled water as described by the comment. FDA has added this exclusion because

such persons are not parties to the transaction and records from such person are not necessary to identify the immediate previous sources and immediate subsequent recipients of food to address credible threats of serious adverse health consequences or death. The comment also asks whether, for bottled water, such a customer would also be the immediate previous source for bottles that are returned to the bottler for reuse. A customer who returns bottles to the bottler would be the nontransporter immediate previous source of the bottles (§ 1.328 of the final rule). As with other sources of its bottles (e.g., a bottle manufacturer), the bottler would be required to keep records of bottles received from customers for reuse.

, a regulated entity would be required to establish written policies and procedures for sanctioning workforce members who fail to comply with the regulated entity's security policies and procedures. The proposed implementation specification for modifications at paragraph (a)(6)(ii)(B) would require a regulated entity to review its written sanctions policies and procedures at least once every 12 months, and, based on that review, modify such policies and procedures as reasonable and appropriate. The proposed implementation specification for application at proposed paragraph (a)(6)(ii)(C) would direct a regulated entity to apply appropriate sanctions against workforce members who fail to comply with such security policies and procedures and to document when it sanctions a workforce member and the circumstances in which it applies such sanctions. The policy choices represented in this NPRM are informed by the compliance challenges OCR has observed through its enforcement activities. These challenges demonstrate that regulated entities would benefit from greater precision and clarity about their legal obligations in the proposed standard. Additionally, according to a recent survey of IT and IT security practitioners in healthcare, careless users were the top cause of data loss and exfiltration, while accidental loss was the second highest cause. Thirty-one percent of respondents indicated that the data loss or exfiltration was caused by a failure of workforce members to follow organizational policies. [511] As described in existing Department guidance, an organization's sanction policies can be an important tool for supporting accountability and improving cybersecurity and data protection. [512] Sanction policies can be used to address the intentional actions of malicious insiders, such as a workforce member that accesses the ePHI of a public figure or steals ePHI to sell as part of an identity-theft ring, as well as the failure of workforce members to comply with policies and procedures, such as failing to secure data on a network server or investigate a potential security incident. Sanction policies that are appropriately applied can improve a regulated entity's general compliance with the HIPAA Rules. Imposing consequences on workforce members who violate a regulated entity's policies and procedures implemented as required by the Security Rule or the HIPAA Rules generally can be effective in creating a culture of HIPAA compliance and improved cybersecurity. Knowledge that there is a negative consequence to noncompliance enhances the likelihood of compliance. [513] Training workforce members on a regulated entity's sanction policy can also promote compliance and greater cybersecurity vigilance by informing workforce members in advance which actions are prohibited and punishable. [514]

(D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have (printed page 14760) been exempted from the access provisions of subsection (d). (31) System identifier and name. A0601-210a USAREC, Enlisted Eligibility Files. (i) Exemption. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k) (5) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or

apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants.

Two commenters recommended the DoD fully implement CMMC requirements to standardize contract requirements to avoid proliferation of unique contract clauses across the Department. One comment suggested the rule should state explicitly that CMMC requirements do not apply to other agencies and advise DoD contractors to seek legal guidance before complying with CMMC requirements if other agency requirements also apply. In addition, several commenters thought the 32 CFR part 170 CMMC Program rule requirements lacked sufficient information about the associated 48 CFR part 204 CMMC Acquisition rule requirements to implement them. One person erroneously identified the DFARS clause 252.204-7021 as part of the 32 CFR part 170 CMMC Program rule, and one person asked what additional rulemaking is needed to implement CMMC requirements. Another person recommended close coordination and synchronization between the two rules. One comment recommended the contract clauses be simplified to be -stand alone-, rather than requiring cognizance of the 32 CFR part 170 CMMC Program rule content. One commenter asked whether contractors must meet CMMC requirements during the solicitation phase, or to view RFPs that contain CUI. Another asked how DoD plans to integrate CMMC requirements into DoD's Adaptive Acquisition Framework. One contractor disagreed with CMMC's pre-award approach, and worried it could create a need to become compliant in anticipation of future solicitations. This commenter posited that any information designated as CUI after contract award will create a -chicken and egg- dilemma for CMMC compliance. Other comments asked whether conditional certifications would be weighted differently than final certifications in the proposal evaluation and award process and suggested that DoD provide 6 months advance notice for all solicitations containing a CMMC requirement. Some comments urged the DoD to describe how DoD will identify CUI in solicitations and when CUI markings should apply in CSP or ESP scenarios. They also requested modification of DoD contracting procedures to provide criteria for identifying CUI information in each contract award along with the corresponding CMMC assessment level. One commenter inquired about the difference between implementing security requirements and assessing compliance. Some comments pertained to other DFARS contractual requirements, rather than CMMC requirements. For example, some recommended changing DFARS clause 252.204-7012 to remove the definition (printed page 83109) of Covered Defense Information and to deviate from a requirement to comply with the NIST SP 800-171 version current at the time of solicitation. In addition, they asked about cost allowability for time and materials or cost type contracts. Some comments posited that costs for reassessment or recertification should be explicitly identified as reimbursable in the 48 CFR part 204

Several comments stated that recouping compliance costs could take years, forcing SMBs into financial debt, contract termination, and exclusion from the market for DoD contracts. One commenter expressed concern about implementation of CMMC as a condition of contract award and the implication that compliance costs are incurred prior to receiving a DoD contract. Response: DoD declined to implement a small entity specific -phased compliance-. Since December 2017, DFARS clause 252.204-7012 has required contractors to implement the NIST SP 800-171 security requirements to provide adequate security applicable for processing, storing, or transmitting CUI in support of the performance of a DoD contract. DoD received numerous comments about the use of ESPs, including MSPs, which do not process, store, or transmit CUI. In response to comments, the DoD has reduced the assessment burden on External Service Providers (ESPs). ESP assessment, certification, and authorization requirements in §§ 170.19(c)(2) and (d)(2) have been updated. ESPs that are not CSPs and do NOT process, store, or transmit CUI, do not require CMMC assessment or certification. Services provided by an ESP are in the OSA's assessment scope. CMMC has taken several steps to keep the cost of compliance with the rule commensurate with the risk to the DoD's information. Level 1 only requires self-assessment, and many contracts with CUI will only require a Level 2 self-assessment. Companies that currently attest that they meet DFARS clause 252.204-7012 should not have

difficulty completing a Level 2 self-assessment. In accordance with the rulemaking process, this rule was reviewed by both DoD cost analysts and OMB economists for realism and completeness. This is a 32 CFR part 170 CMMC Program rule, not an acquisition rule. The 48 CFR part 204 CMMC Acquisition rule will address implementation of CMMC as it pertains to DoD contracts. d. Detailed Cost Analysis Comment: A few comments suggested a detailed cost analysis should consider SMBs of various sizes, types, and challenges to ensure compliance is sustainable. One comment asked whether a profit margin analysis was performed, while another asserted that other third-party assessments are less expensive than the estimates for CMMC assessment. Another stated CMMC Level 3 cost estimates are too low and suggested using costs associated with SECRET-level networks for calculation. Response: The DoD provided an analysis of costs to meet CMMC Level 1 and 2 requirements in the regulatory impact analysis for this rule. The cost estimates provided for this rule represent average costs for companies to comply with CMMC requirements, including the need for self-assessment or independent assessment against the specified standards. Comparing costs with other third-party security audits presumes that the security and assessment requirements are identical, and DoD disagrees with that assumption.

Since section 806 decisions rely on intelligence information, the operation of the rule presents no barrier to participation in the DoD market for either existing participants or new entrants. (printed page 67249) d. De Facto Debarment/Suspension Comment: Several respondents stated that the exercise of the exclusionary authority in the rule could result in a de facto debarment or suspension without any due process for the affected offeror. Response: Risk will be evaluated on case-by-case basis, and any exclusion will be for a particular source selection and not a blanket exclusion. Offerors are eligible to compete for future solicitations even after section 806 has excluded them from a particular source selection. e. Security Comment: One respondent commented that the rule could unintentionally but negatively impact the Federal Government's security because it prevents DoD from informing suppliers about supply chain risks that DoD believes exist and prevents any consultation with offerors. Response: This will be taken into consideration in any instance that the section 806 authority is utilized. 7. Qualification standard Comment: Three respondents commented that the interim rule should provide more guidance regarding the qualification standard(s) that may be established to reduce supply chain risk. One respondent urged DoD to develop the systems and data security requirements for covered procurements and issue them to potential offerors during the procurement process as a requirement for bid eligibility. This approach would focus the use of this clause to procurements for covered systems or covered items of supply and would increase competition by limiting unnecessary disqualification of offerors (and contractors and subcontractors/suppliers) that could meet the Government's requirements. Another respondent commented that the rule should be amended to provide more specificity as to the type of qualification standards that may be established for the purposes of reducing supply chain risk in the acquisition of covered systems. Response: DoD has no present plans to use section 806 authority to exclude a source based on failure to meet a qualification standard to reduce supply chain risk. To use this authority DoD must first develop qualification standards in accordance with the requirements of 10 U.S.C. 2319, which include providing the qualification requirements to potential offerors. 8. Synchronize/Harmonize With Related Rules/Initiatives Comment:

In CMMC 1.0, there was no intent to change the meaning of NIST requirements except those referenced as modified. These minor discrepancies are now resolved as all FCI requirements use the exact FAR language and all CUI requirements use the exact language from the relevant NIST guidelines. The requirements in CMMC Level 3 are derived from NIST SP 800-172 with DoD-approved parameters. Commenters requesting revisions to NIST guidelines should respond to the NIST public comment periods. There is no CMMC-specific cyber incident reporting requirement or need for associated medium assurance certificate. Comment: Several comments sought clarification on the alignment and relative authority or precedence of the CMMC requirements to Federal, Legislative, Statutory, Regulatory, or DoD Organizational policy, DoD instructions, and FAQs. Response: The CMMC Program requirements will be required once implemented in the DFARS and will have the same relative authority of any other DoD contract requirement. The CMMC Program relates to and incorporates elements of the following authorities: Executive Order No. 13556, Controlled Unclassified Information, 75 FR 68675 (November 4, 2010), which establishes an open and uniform program for managing [unclassified] information that requires safeguarding or dissemination controls; 32 CFR part 2002, which describes the executive branch's Controlled Unclassified Information Program and establishes policy for designating, handling, safeguarding, and decontrolling information that qualifies as CUI when processed, stored, or transmitted on a federal or non-federal information

system; FAR clause 52.204-21, Basic Safeguarding of Covered Contractor Information Systems, which, as applicable, requires contractors to apply certain basic safeguarding procedures on covered contractor information systems that process, store, or transmit FCI; and DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, which, as applicable, requires defense contractors to implement NIST SP 800-171 Rev 2 requirements on unclassified covered contractor information systems that process, store, or transmit covered defense information. Additional DoD instructions and manuals address DoD information security policy, including DoDI 5200.48 CUI which establishes policy, assigns responsibilities, and prescribes procedures for CUI throughout the DoD for federal and on non-federal information systems to include the implementation of NIST SP 800-171 Rev 2. A requirement for CMMC assessments provides DoD assurance that contractors have implemented required cybersecurity protections. The requirements of this rule will be implemented in an associated 48 CFR acquisition rule regarding CMMC. 21. CMMC Assessment Comment:

DoD agrees that a separate approval of contractor scrap procedures is neither practical nor necessary; however, the basic minimum requirements of an adequate scrap procedure are integral to proper application of the clause. Accordingly, the language referring to scrap procedure approvals at DFARS 252.245-70XX(j)(1) has been deleted from the final rule; the remaining language has been retained at paragraph (h) of 252.245-7004. Comment: In reference to DFARS 252.245-70XX(j)(i)(ii), a respondent recommended retaining the current language found in DFARS 245.610-3(1)(iv)(B), as follows: 'When commingling is approved, the net proceeds for contractors with an approved scrap procedure will ensure (that sales) proceeds are appropriately applied to an overhead account.' DoD Response: While the requirement is still relevant, it is a normal part of a property administrator's oversight function; therefore, the language is more suitable to internal DoD component guidance, e.g., DCMA instructions. Comment: A respondent recommended deleting the requirement for a scrap warranty at DFARS 252.245-70XX(j)(3). DoD Response: The referenced language has been modified to allow Government discretion in requiring a scrap warranty. Comment: A respondent recommended moving the requirements of DFARS 252.245-70XX(k), Disposal of contractor inventory for NATO cooperative services, to DFARS part 245 or providing clarification that its requirements are a Government responsibility. DoD Response: The language has been deleted from the final rule clause, as DoD support to NATO cooperative projects is already covered under DFARS 225.871. F. Other Changes 1. Comment: A respondent identified 'untability' as a typographical error at DFARS 252.245-70XX(j)(1)(i). DoD Response: The term has been changed to 'accountability.' 2. Comment: A respondent stated that the proposed changes do a good job of cleaning up and consolidating the plant clearance process and that the new PGI for DFARS Case 2009-D008 also looks good. DoD Response: Noted. 3. The following changes have been incorporated into the final rule based on internal DoD coordinations: Deleted the reference to FAR 52.245-2 at 245.107 because the FAR clause 52.245-2 is not a stand-alone clause and can only be used in conjunction with FAR 52.245-1; Added clarifying language on property condition at 245.602-1(3); Clarified that 245.602-1 applies only to termination inventory and that such inventory may be verified by appropriate technical personnel; Added clarifying language at 245.602-3 on disposition of contractor inventory in overseas locations; arrangement of inspection of property and security requirements; and consideration by the plant clearance officer of any special disposition requirements, such as demilitarization; and trade security requirements; Added 245.7101-5(d), Other disposal actions, to conform to the DD Form 1641;

STEP itself does not imply any particular implementation form or security policy. Certain policies are more easily implemented with the SQL/STEP architecture than others. In Section 4, three broad classes of security policies are briefly described, accompanied by a comparison of particular requirements with the facilities of SQL. The policy classes are: a role based policy, a mandatory access control policy for confidentiality, and a mandatory access control policy for integrity. Inference and aggregation are usually considered threats to mandatory access control policies, but they are threats in any environment. There are also a number of DBMS specific security issues, such as referential integrity and polyinstantiation. Classic OS problems such as deadlock and transaction completion must also be considered. - Database Schema: The database schema must be well designed to ensure that aggregation and inference are not threats. - Transaction Management: The SQL processor must prevent denial of service due to deadlock. The SQL processor must provide appropriate transaction management features: incomplete transactions can result in loss of external consistency, i.e., the tables and elements are not 'synchronized.' - Modification: The SQL processor is responsible for maintaining access control for SQL level objects. The SQL processor is responsible for enforcing external consistency issues, such as type checking and ranges. - Retrieval: The SQL

processor is responsible for maintaining access control for SQL level objects.

(vii) Develop and maintain security documentation of the security authorization request to the CSA. Documentation may include: (A) SSPs. (B) Security assessment reports. (C) Plans of actions and milestones. (D) Risk assessments. (E) Authorization decision letters. (F) Contingency plans. (G) Configuration management plans. (H) Security configuration checklists. (I) System interconnection agreements. (3) Information systems security officer (ISSO). The ISSM may assign an ISSO. If assigned, the ISSO will: (i) Verify the implementation of the contractor's information system security program as delegated by the ISSM. (ii) Ensure continuous monitoring strategies and verify corrective actions to the ISSM. (iii) Conduct self-inspections and verify corrective actions to the ISSM. (4) Information system users. All information system users will: (i) Comply with the information system security program requirements as part of their responsibilities for protecting classified information. (ii) Be accountable for their actions on an authorized information system. (iii) Not share any authentication mechanisms (including passwords) issued for the control of their access to an information system. (iv) Protect authentication mechanisms at the highest classification level and most restrictive classification category of information to which the mechanisms permit access. (v) Be subject to monitoring of their activity on any classified network, understanding that the results of such monitoring can be used against them in a criminal, security, or administrative proceeding or action. (vi) Notify the ISSM or ISSO when access to a classified system is no longer required. (d) Information system security life-cycle. The CSA-provided guidance on the information system security life-cycle is based on the risk management framework outlined in NIST special publication 800-37 that emphasizes: (1) Building security into information systems during initial development. (2) Maintaining continuous awareness of the current state of information system security. (3) Keeping contractor management informed to facilitate risk management decisions. (4) Supporting reciprocity of information system authorizations. (e) Risk management framework. The risk management framework is a seven-step process used for managing information system security-related risks. These steps will be used to help ensure security capabilities provided by the selected security controls are implemented, tested, validated, and approved by the USG authorizing official with a degree of assurance appropriate for the information system. This process accommodates an on-going risk mitigation strategy. (1) Prepare. The contractor will execute essential activities at the organization, mission and business process, and system levels of the organization to help prepare the organization to manage its security and privacy risks using the Risk Management Framework. (2) Categorize.

CIS Control 3 · Data Protection Develop processes and technical controls to identify, classify, securely handle, retain, and dispose of data. Data is no longer only contained within an enterprise's border, it is in the cloud, on portable end-user devices where users work from home, and is often shared with partners or online services who might have it anywhere in the world. In addition to sensitive data an enterprise holds related to finances, intellectual property, and customer data, there also might be numerous international regulations for protection of personal data. Data privacy has become increasingly important, and enterprises are learning that privacy is about the appropriate use and management of data, not just encryption. Data must be appropriately managed through its entire lifecycle. These privacy rules can be complicated for multi-national enterprises, of any size, however there are fundamentals that can apply to all. Once attackers have penetrated an enterprise's infrastructure, one of their first tasks is to find and exfiltrate data. Enterprises might not be aware that sensitive data is leaving their environment because they are not monitoring data outflows. While many attacks occur on the network, others involve physical theft of portable end-user devices, attacks on service providers or other partners holding sensitive data. Other sensitive enterprise assets may also include non-computing devices that provide management and control of physical systems, such as Supervisory Control and Data Acquisition (SCADA) systems. The enterprise's loss of control over protected or sensitive data is a serious and often reportable business impact. While some data is compromised or lost as a result of theft or espionage, the vast majority are a result of poorly understood data management rules, and user error. The adoption of data encryption, both in transit and at rest, can provide mitigation against data compromise, and more importantly, is a regulatory requirement for most controlled data.

According to nist_sp800-66r2: <!-- image --> ## NIST Special Publication 800 NIST SP 800-66r2 ## Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule A Cybersecurity Resource Guide Jeffrey A. Marron This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-66r2> <!-- image --> ## NIST Special Publication 800 NIST SP

800-66r2 ## Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule A Cybersecurity Resource Guide Jeffrey A. Marron Applied Cybersecurity Division Information Technology Laboratory This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-66r2> February 2024 <!-- image --> U.S. Department of Commerce Gina M. Raimondo, Secretary National Institute of Standards and Technology Certain commercial equipment, instruments, software, or materials, commercial or non-commercial, are identified in this paper in order to specify the experimental procedure adequately. Such identification does not imply recommendation or endorsement of any product or service by NIST, nor does it imply that the materials or equipment identified are necessarily the best available for the purpose. There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. Organizations are encouraged to review all draft publications during public comment periods and provide feedback to NIST.

- GLYPH<math>\text{c}=31, \text{font}=\text{HHCKCL+Webdings}> The types of threats for which the IDPS should provide protection. Evaluators should state, as specifically as possible, the concerns that the organization has regarding the types of threats that originate both outside the organization and inside the organization (insider threats). Insider threats should encompass not only users who attack the system from within, but also authorized users who overstep their privileges, thereby violating organizational security policy or laws. - GLYPH<math>\text{c}=31, \text{font}=\text{HHCKCL+Webdings}> Any needs to monitor system and network usage for acceptable use violations or non-security reasons. In some organizations, there are system use policies that target user behaviors that may be considered personnel management rather than system security issues. These might include accessing Web sites that provide content of questionable taste or value (such as pornography) or using the organization's systems to send email or other messages to harass individuals. Some IDPSs provide features that accommodate detecting such events. Monitoring usage can also assist organizations in determining when systems and networks are reaching capacity and might need to be upgraded or replaced. IDPSs can protect the systems of an organization, but at a price. It makes little sense to incur additional expense for IDPS features if the organization does not have sufficient systems or personnel to use them. Evaluators should consider the following: - GLYPH<math>\text{c}=31, \text{font}=\text{HHCKCL+Webdings}> The budget for acquisition and life cycle support of IDPS hardware, software, and infrastructure. The total cost of ownership of IDPSs well exceeds acquisition costs. Other costs may be associated with acquiring systems on which to run software components, deploying additional networks, providing sufficient storage for IDPS data, obtaining specialized assistance in installing and configuring the system, and training personnel.

(6) Description of goods; or (e) Entering into an agreement with the nontransporter immediate previous source located in the United States and/or the nontransporter immediate subsequent recipient located in the United States to establish, maintain, or establish and maintain, the information in § 1.352(a), (b), (c), or (d). The agreement must contain the following elements: (1) Effective date; (2) Printed names and signatures of authorized officials; (3) Description of the records to be established and/or maintained; (4) Provision for the records to be maintained in compliance with § 1.360, if the agreement provides for maintenance of records; (5) Provision for the records to be available to FDA as required by § 1.361, if the agreement provides for maintenance of records; (6) Acknowledgement that the nontransporter assumes legal responsibility under § 1.363 for establishing and/or maintaining the records as required by this subpart; and (7) Provision that if the agreement is terminated in writing by either party, responsibility for compliance with the applicable establishment, maintenance, and access provisions of this subpart reverts to the transporter as of the date of termination. § 1.360 What are the record retention requirements? (a) You must create the required records when you receive and release food, except to the extent that the information is contained in existing records. (b) If you are a nontransporter, you must retain for 6 months after the dates you receive and release the food all required records for any food having a significant risk of spoilage, loss of value, or loss of palatability within 60 days after the date you receive or release the food. (c) If you are a nontransporter, you must retain for 1 year after the dates you receive and release the food all required records for any food for which a significant risk of spoilage, loss of value, or loss of palatability occurs only after a

minimum of 60 days, but within 6 months, after the date you receive or release the food. (d) If you are a nontransporter, you must retain for 2 years after the dates you receive and release the food all required records for any food for which a significant risk of spoilage, loss of value, or loss of palatability does not occur sooner than 6 months after the date you receive or release the food, including foods preserved by freezing, dehydrating, or being placed in a hermetically sealed container. (e) If you are a nontransporter, you must retain for 1 year after the dates you receive and release the food all required records for animal food, including pet food.

relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (7) System identifier and name. CIG 23, Public Affairs Files. (i) Exemption. During the course of processing a General Counsel action, exempt materials from other systems of records may in turn become part of the case records in this system. To the extent that copies of exempt records from those 'other' systems of records are entered into the Public Affairs Files, the Office of the Inspector General hereby claims the same exemptions for the records from those 'other' systems that are entered into this system, as claimed for the original primary systems of records which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(1), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. Records are only exempt from pertinent provisions of 5 U.S.C. 552a to the extent (A) such provisions have been identified and an exemption claimed for the original record and (B) the purposes underlying the exemption for the original record still pertain to the record which is now contained in this system of records. In general, the exemptions were claimed in order to protect properly classified information relating to national defense and foreign policy, to avoid interference during the conduct of criminal, civil, or administrative actions or investigations, to ensure protective services provided the President and others are not compromised, to protect the identity of confidential sources incident to Federal employment, military service, contract, and security clearance determinations, to preserve the confidentiality and integrity of Federal testing materials, and to safeguard evaluation materials used for military promotions when furnished by a confidential source. The exemption rule for the original records will identify the specific reasons why the records are exempt from specific provisions of 5 U.S.C. 552a . (8) System identifier and name. CIG-29, Privacy and Civil Liberties Complaint Reporting System. (i) Exemption. Any portion of this record system which falls within the provisions of 5 U.S.C. 552a (j)(2), (k)(2) and (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I). (ii) Authority. 5 U.S.C. 552a(j)(2) , (k)(2), and (k)(5). (iii) Reasons.

If an individual asks for his or her records and does not cite or reasonably imply either the Privacy Act or the Freedom of Information Act, and another prescribing directive or regulation authorizes the release, the records should be released under that other directive or regulation and not the PA or the FOIA. Examples of functional requests are military members asking to see their Official Military Personnel Records or civilian employees asking to see their Official Personnel Folder. (i) Procedures for denying or limiting an individual's right to access or amendment and the role of the Denial Authority. (1) The only officials authorized to deny a request for records or a request to amend records in a PA system of records pertaining to the requesting individual, are the appropriate Denial Authorities, their designees, or the Secretary of the Army who will be acting through the General Counsel. (2) Denial Authorities are authorized to deny requests, either in whole or in part, for notification, access and amendment of Privacy Act records contained in their respective areas of responsibility. (i) The Denial Authority may delegate all or part of their authority to a division chief under his supervision within the Agency in the grade of 0-5/GS-14 or higher. All delegations must be in writing. (ii) The Denial Authority will send the names, office names, and telephone numbers of their delegates to the DA Freedom of Information and Privacy Office. (iii) If a Denial Authority delegate denies access or amendment, the delegate must clearly state that he or she is acting on behalf of the Denial Authority, who must be identified by name and position in the written response to the requester. Denial Authority designation will not delay processing privacy requests/actions. (iv) The official Denial Authorities are for records under their authority (See appendix B of this part). The individuals designated as Denial Authorities

under this part are the same individuals designated as Initial Denial Authorities under AR 25-55, the Department of the Army Freedom of Information Act Program. However, delegation of Denial Authority pursuant to this part does not automatically encompass delegation of Initial Denial Authority under AR 25-55. Initial Denial Authority must be expressly delegated pursuant to AR 25-55 for an individual to take action on behalf of an Initial Denial Authority under AR 25-55. (3) The custodian of the record will acknowledge requests for access made under the provisions of the Privacy Act within 10 working days of receipt.

According to Cybersecurity Framework Profile for Liquefied Natural Gas, Category Prioritization Summary: Workshop participants were asked to identify Categories most relevant to each mission objective, and then to prioritize those Categories as high-priority, medium-priority, or starred-priority using the following descriptions: - High-Priority Categories were considered the most critical for accomplishing a mission objective. - Medium-Priority Categories were considered important to a mission objective, although not as important as high-priority Categories. - Starred-Priority Categories were identified as being relevant to a mission objective, but not with the same urgency as other priority Categories. Profiles should be tailored to individual operating environments and organizational risk tolerances. The identified Category priorities, shown in Sec. 6.1, are intended to help focus resources on cybersecurity activities that participants identified as particularly relevant. The intent of this Profile is to suggest areas of focus priority pertinent to the LNG lifecycle. A user of this Profile could repeat the workshop steps to develop their own Profile based on their organization's unique needs and resource considerations. The tables in Sec. 6.1 do not include the following Categories: Awareness and Training (PR.AT), Detection Processes (DE.DP), Communications (RS.CO), Analysis (RS.AN), Mitigation (RS.MI), Improvements (RS.IM), Improvements (RC.IM), and Communications (RC.CO). The workshop participants did not identify these Categories as relevant during the workshop. An organization should review all Categories when identifying high-priority, medium-priority, and starred-priority Categories on which it needs to focus.

Subpart B-Requests for Access and Amendment to Records 310.3 Requesting access to records. 310.4 Access exemptions. 310.5 Responses to requests for access to records. 310.6 Appeals from denials of requests for access to records. 310.7 Requests for amendment or correction of records. 310.8 Civil remedies. 310.9 Requests for an accounting of record disclosures. 310.10 Fees. 310.11 Other rights and services. Subpart C-Exemption Rules 310.12 Types of exemptions. 310.13 Exemptions for DoD-wide systems. 310.14 Department of the Air Force exemptions. 310.15 Department of the Army exemptions. 310.16 Department of the Navy exemptions. 310.17 Exemptions for specific Marine Corps record systems. 310.18 Defense Contract Audit Agency (DCAA) exemptions. 310.19 Defense Information Systems Agency (DISA) exemptions. 310.20 Defense Intelligence Agency (DIA) exemptions. 310.21 Defense Logistics Agency (DLA) exemptions. 310.22 Defense Security Service (DSS) exemptions. 310.23 Defense Threat Reduction Agency (DTRA) exemptions. 310.24 National Geospatial-Intelligence Agency (NGA) exemptions. 310.25 National Guard Bureau (NGB) exemptions. 310.26 National Reconnaissance Office (NRO) exemptions. 310.27 National Security Agency (NSA) exemptions. 310.28 Office of the Inspector General (OIG) exemptions. 310.29 Office of the Secretary of Defense (OSD) exemptions. Authority: 5 U.S.C. 552a . Subpart A-General Provisions §-310.1 Purpose. This part contains the rules that the Department of Defense (Department or DoD) follows under the Privacy Act of 1974, 5 U.S.C. 552a . These rules should be read together with the Privacy Act. The rules in this part apply to all records in Privacy Act systems of records maintained by the Department. They describe the procedures by which individuals may request access to records about themselves, request amendment or correction of those records, and request an accounting of disclosures of those records by the Department to other entities outside the Department. In addition, the Department processes all Privacy Act requests for access to records under the Freedom of Information Act (FOIA), 5 U.S.C. 552 , following the rules contained in 32 CFR part 286 , giving individuals the benefit of both statutes. §-310.2 Definitions. DoD Components means the Office the Office of the Secretary of Defense (OSD), the Military Departments, the Office of the Chairman of the Joint Chiefs of Staff and the Joint Staff, the Combatant Commands, the Office of the Inspector General of the Department of Defense, the Defense Agencies, the DoD Field Activities, and all other organizational entities within the DoD (referred to collectively in this part as the ·DoD Components·). Individual means a citizen of the United States or an alien lawfully admitted for permanent residence, as defined in the Privacy Act. Maintain includes maintain, collect, use or disseminate, as defined in the Privacy Act. Record

because this rule will only have an impact on a firm, or a subsidiary of a firm, in which the government of a country that is a state sponsor of terrorism has a significant interest. The number of domestic entities significantly impacted by this rule will be minimal, if any. For the definition of "small business," the Regulatory Flexibility Act refers to the Small Business Act, which in turn allows the U.S. Small Business Administration (SBA) Administrator to specify detailed definitions or standards (5 U.S.C. 601(3) and 15 U.S.C. 632(a)). The SBA regulations at 13 CFR 121.105 discuss who is a small business: "(a)(1) Except for small agricultural cooperatives, a business concern eligible for assistance from SBA as a small business is a business entity organized for profit, with a place of business located in the United States, and which operates primarily within the United States or which makes a significant contribution to the U.S. economy through payment of taxes or use of American products, materials or labor." V. Paperwork Reduction Act The rule contains information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C chapter 35); however, these changes to the DFARS do not impose additional information collection requirements to the paperwork burden previously approved under OMB Control Number 0704-0187, entitled "Information Collection in Support of the DoD Acquisition Process (Various Miscellaneous Requirements)." This final rule removes provision 252.209-7001, Disclosure of Ownership or Control by the Government of a Terrorist Country, and replaces it with provision 252.225-7050, Disclosure of Ownership or Control by the Government of a Country that is a State Sponsor of Terrorism. The burden in clearance 0704-0187 previously associated with the provision 252.209-7001, which is now associated with provision 252.225-7050, remains unchanged and is estimated at 1 hour, because such disclosure occurs rarely, if ever. 10 U.S.C. prohibits award to a firm or a subsidiary of a firm if the government of country that is a state sponsor of terrorism has a significant interest in the firm or subsidiary, unless the Secretary of Defense grants a waiver. (printed page 73489) List of Subjects in 48 CFR Parts 204 , 209 , 212 , 225 , and 252 Government procurement Manuel Quinones, Editor, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204 , 209 , 212 , 225 , and 252 are proposed to be amended as follows: 1. The authority citation for parts 204, 209, 212, 225, and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 . PART 204-ADMINISTRATIVE MATTERS 2. Amend section 204.1202 by: a. Removing paragraph (2)(i); b. Redesignating paragraphs (2)(ii) through (x) as (2)(i) through (ix), respectively; and c. Adding new paragraph (2)(x) to read as follows: 204.1202 Solicitation provision. * * * * * (2) ** *

Any portions of this system of records which fall under the provisions of 5 U.S.C. 552a(k)(2) and (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3), (d), (e)(1), (e)(4)(G), (H), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons. (A) From subsection (c)(3) because disclosures from this system could interfere with the just, thorough and timely resolution of the complaint or inquiry, and possibly enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying or fabricating evidence or documents. (B) From subsection (d) because disclosures from this system could interfere with the just, thorough and timely resolution of the complaint or inquiry, and possibly enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying or fabricating evidence or documents. Disclosures could also subject sources and witnesses to harassment or intimidation which jeopardize the safety and well-being of themselves and their families. (C) From subsection (e)(1) because the nature of the investigation functions creates unique problems in prescribing specific parameters in a particular case as to what information is relevant or necessary. Due to close liaison and working relationships with other Federal, state, local, and foreign country law enforcement agencies, information may be received which may relate to a case under the investigative jurisdiction of another government agency. It is necessary to maintain this information in order to provide leads for appropriate law enforcement purposes and to establish patterns of activity which may relate to the jurisdiction of other cooperating agencies. (D) From subsection (e)(4)(G) through (H) because this system of records is exempt from the access provisions of subsection (d). (E) From subsection (f) because the agency's rules are inapplicable to those portions of the system that are exempt and would place the burden on the agency of either confirming or denying the existence of a record pertaining to a requesting individual might in itself provide an answer to that individual relating to an on-going investigation. The conduct of a successful investigation leading to the indictment of a criminal offender precludes the applicability of established agency rules relating to verification of record, disclosure of the record to that individual, and record amendment procedures for this record system. (5) System identifier and name. CIG 01, Privacy Act and Freedom of Information Act Case Files.

(i) Exemption.

(ii) The Board shall review and approve all computer matching agreements between the Department of Defense and the other Federal, State or local governmental agencies, as well as memoranda of understanding when the match is internal to the Department of Defense, to ensure, under 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R, appropriate procedural and due process requirements shall have been established before engaging in computer matching activities. (c) The Defense Privacy Board Legal Committee. (1) Membership. The Committee shall consist of the Director, DPO, DA&M, who shall serve as the Chair and the Executive Secretary; the GC, DoD, or designee; and civilian and/or military counsel from each of the DoD Components. The General Counsels (GCs) and The Judge Advocates General of the Military Departments shall determine who shall provide representation for their respective Department to the Committee. This does not preclude representation from each office. The GCs of the other DoD Components shall provide legal representation to the Committee. Other DoD civilian or military counsel may be appointed by the Executive Secretary, after coordination with the DoD Component concerned, to serve on the Committee on those occasions when specialized knowledge or expertise shall be required. (2) Responsibilities. (i) The Committee shall serve as the primary legal forum for addressing and resolving all legal issues arising out of or incident to the operation of the DoD Privacy Program. (ii) The Committee shall consider legal questions regarding the applicability of 5 U.S.C. 552a, OMB Circular A-130, and DoD 5400.11-R and questions arising out of or as a result of other statutory and regulatory authority, to include the impact of judicial decisions, on the DoD Privacy Program. The Committee shall provide advisory opinions to the Defense Privacy Board and, on request, to the DoD Components. (d) The DPO. (1) Membership. It shall consist of a Director and a staff. The Director also shall serve as the Executive Secretary and a member of the Defense Privacy Board; as the Executive Secretary to the Defense Data Integrity Board; and as the Chair and the Executive Secretary to the Defense Privacy Board Legal Committee. (2) Responsibilities. (i) Manage activities in support of the Privacy Program oversight responsibilities of the DA&M. (ii) Provide operational and administrative support to the Defense Privacy Board, the Defense Data Integrity Board, and the Defense Privacy Board Legal Committee. (iii) Direct the day-to-day activities of the DoD Privacy Program. (iv) Provide guidance and assistance to the DoD Components in their implementation and execution of the DoD Privacy Program. (v) Review DoD legislative, regulatory, and other policy proposals which implicate information privacy issues relating to the Department's collection, maintenance, use, or dissemination of personal information, to include any testimony and comments having such implications under DoD Directive 5500.1.

regarding Supply Chain Risk Management. The commenter further requested a DoD-level working group outline how DoD program offices might identify which components are mission or safety critical or which associated production processes should be identified as CTI. That commenter recommended this rule be held in abeyance until AT&L [sic] has reviewed and provided their insight into the impacts of CMMC on existing DoD acquisition documentation and deliverables. Yet another comment recommended that this proposed DFARS ruling be vetted through AT&L, ASD and OUSD [sic] as a minimum to determine if changes would be required in the Program Protection Improvement Plan and System Security Plan. Lastly, this commenter recommended the DoD engage with NDIA and ISO/IEC to develop alternate standards for securing data and supply chains. Response: CMMC Program requirements apply to contractor-owned information systems that process, store, or transmit FCI and CUI and do not apply to systems developed or acquired for DoD through the formal Defense Acquisition System (DAS). Therefore, integrating the CMMC assessment process and internal DAS processes (including technical reviews prior to RFP development) is not appropriate and is beyond the scope of this rule. Note that CMMC applicability is broader than just the Major Defense Acquisition Programs. DoD's organizational alignment of responsibilities (between OSBP and SBA military offices) for assisting small businesses or establishing new offices within OSD is beyond the scope of this rule. Due to national security concerns, DoD declines the recommendation to further delay implementation of the CMMC Program. Each passing day in delay of implementing the security requirements for safeguarding DoD FCI and CUI increases the risk for exfiltration of non-public information on unsecured nonfederal systems that (printed page 83106) may result in the loss of DoD's technological advantages in its warfighting capabilities and programs. Discussions regarding acquisition strategies and frameworks are beyond the scope of this CMMC rule. The CMMC Program does not alleviate or supersede any existing requirements of the Adaptive Acquisition Framework, nor does it alter any statutory or regulatory requirement for acquisition program documentation or deliverables. Note that CMMC Program requirements do not apply to systems delivered to DoD. DoD Instructions for

required acquisition program documentation are beyond the scope of this rule. CMMC assessment certifications are not integrated into System Security Plans (SSPs).

146 NARA, CUI Notice 2019-01: Controlled Unclassified Information (CUI) Coversheets and Labels MP.L2-3.8.4 · Media Markings CMMC Assessment Guide · Level 2 | Version 2.13 164 Example You were recently contacted by the project team for a new DoD program. The team said they wanted the CUI in use for the program to be properly protected. When speaking with them, you realize that most of the protections will be provided as part of existing enterprise cybersecurity capabilities. They also mentioned that the project team will use several USB drives to share specific data. You explain that the team must ensure the USB drives are externally marked to indicate the presence of CUI [a]. The project team labels the outside of each USB drive with an appropriate CUI label following NARA guidance [a]. Further, the labels indicate that distribution is limited to those employees supporting the DoD program [a]. Potential Assessment Considerations · Are all media containing CUI identified [a,b]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.8.4

·\$121,500,000 Nonrecurring Engineering cost (\$2,700,000 per entity × 45 entities being certified), and ·\$23,520,000 Recurring Engineering cost (\$490,000 per entity × 45 entities being certified) + (\$490,000 per entity × 3 entities performing affirmations) ·\$145,432,897 Total Cost = Certification and Affirmation Cost (printed page 83209) (\$412,897) + Nonrecurring Engineering cost (\$121,500,000) + Recurring Engineering cost (\$23,520,000), or \$145,432,897. Projected Reporting, Recordkeeping, and Compliance Requirements The CMMC Program provides for the assessment of contractor implementation of cybersecurity requirements to enhance confidence in contractor protection of unclassified information within the DoD supply chain. CMMC contractual requirements are implemented under the 48 CFR part 204 CMMC Acquisition rule, with associated rulemaking for the CMMC Program requirements (e.g., CMMC Scoring Methodology, certificate issuance, information accessibility) under the 32 CFR part 170 CMMC Program rule. The 32 CFR part 170 CMMC Program rule includes two separate information collection requests (ICR), one for the CMMC Program and one for CMMC eMASS. This information collection is necessary to support the implementation of the CMMC assessment process for Levels 2 and 3 certification assessment, as defined in §§ 170.17 and 170.18 respectively. The CMMC Level 2 certification assessment process is conducted by Certified Assessors, employed by CMMC Third-Party Assessment Organizations (C3PAOs). During the assessment process, Organizations Seeking Certification [66] (OSCs) hire C3PAOs to conduct the third-party assessment required for certification. The CMMC Level 3 certification assessment process is conducted by the Defense Contract Management Agency (DCMA) Defense Industrial Base Cybersecurity Assessment Center (DIBCAC). Use of the Information Level 1 and Level 2 CMMC Self-Assessments. Organizations Seeking Assessment [67] (OSAs) follow procedures as defined in §§ 170.15(a)(1) and 170.16(a)(1) to conduct CMMC Level 1 and Level 2 self-assessments on their information systems to determine conformance with the information safeguarding requirements associated with the CMMC level requirements. The Level 1 and Level 2 self-assessment information collection reporting and recordkeeping requirements will be included in a modification of an existing Defense Federal Acquisition Regulation Supplement (DFARS) collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Modifications to this DFARS collection will be addressed as part of the 48 CFR part 204 CMMC Acquisition final rule. CMMC Level 2 Certification Assessment The Level 2 certification assessment information collection burden for reporting and recordkeeping requirements are included in the 32 CFR part 170 CMMC Program rule. The information collection burden for the OSCs to upload affirmations in SPRS is included in the 48 CFR part 204

61. ·Sec. 3009(a)(1)(A) of the PHSA, as added by sec. 13101 of the HITECH Act (codified at 42 U.S.C. 300jj-19(a)(1)). Back to Citation 62. · See Public Law 116-321, 134 Stat. 5072, adding sec. 13412 (Jan. 5, 2021) (codified at 42 U.S.C. 17941); see also 42 U.S.C. 17931 et seq. Back to Citation 63. · See Public Law 116-321, 134 Stat. 5072, adding sec. 13412 (Jan. 5, 2021) (codified at 42 U.S.C. 17941); see also sec. 13401 of Public Law 111-5, 123 Stat. 260 (codified at 42 U.S.C. 17931) (The HITECH Act adopts the same definition of business associate as the HIPAA Rules.); 45 CFR 160.103 (definition of Business associate). Back to Citation 64. ·The Security Rule is codified at 45 CFR part 160 and subparts A and C of 45 CFR part 164. Back to Citation 65. · See 45 CFR 164.306(a)(1). Back to Citation 66. · See 45 CFR 164.306(a)(2). Back to Citation 67. · See 45 CFR 164.306(a)(3). Back to Citation 68. · See 45 CFR 164.306(a)(4). Back to Citation 69. · See sec. 262(a) of Public Law 104-191, 110 Stat. 2025 (Aug. 21, 1996), adding sec. 1173(d) (codified at 42 U.S.C.

1320d-2(d)). Back to Citation 70. 63 FR 43242 (Aug. 12, 1998). Back to Citation 71. Id. at 43244. Back to Citation 72. Id. at 43244, 43249, 43260-61. Back to Citation 73. Id. at 43249. Back to Citation 74. · See 68 FR 8334 , 8335 (Feb. 20, 2003). Back to Citation 75. Id.; see also 63 FR 43242 , 43249 (Aug. 12, 1998). Back to Citation 76. 63 FR 43242 , 43250 (Aug. 12, 1998). Back to Citation 77. Id. Back to Citation 78. Id. at 43249-50. Back to Citation 79. Id. at 43250. Back to Citation 80. 45 CFR parts 160 and subparts A and C of 45 CFR part 164 ; 68 FR 8334 (Feb. 20, 2003). Back to Citation 81. 68 FR 8334 , 8335 , 8371-72 (Feb. 20, 2003). Back to Citation 82. Id. Back to Citation 83. Id. Back to Citation 84. Id. at 8335. Back to Citation 85. Id. Back to Citation 86. Id. at 8336. Back to Citation 87. Id. at 8343. Back to Citation 88. Id. at 8346. Back to Citation 89. Id. Back to Citation 90. Id. Back to Citation 91. Id. Back to Citation 92. Id. Back to Citation 93. Id. at 8336. Back to Citation 94. · Statement of Organization, Functions, and Delegations of Authority, Centers for Medicare & Medicaid Services, 68 FR 60694 (Oct. 23, 2003). Back to Citation 95. · Office for Civil Rights; Delegation of Authority, U.S. Department of Health and Human Services, 74 FR 38630 (Aug. 4, 2009); see also · Statement of Organization, Functions, and Delegations of Authority, Centers for Medicare & Medicaid Services, 74 FR 38663 (Aug. 4, 2009). Back to Citation 96. 75 FR 40868 (July 14, 2010). Back to Citation 97. Id. at 40871. Back to Citation 98. Id. Back to Citation 99. 78 FR 5565 (Jan. 25, 2013). In addition to finalizing requirements of the HITECH Act that were proposed in the NPRM, the Department adopted modifications to the Enforcement Rule not previously adopted in an earlier interim final rule, 74 FR 56123 (Oct. 30, 2009), and to the Breach Notification Rule not previously adopted in an interim final rule, 74 FR 42739

HIPAA Security Rule section 164.308 (Administrative Safeguards) addresses security incident procedures. Covered entities and business associates must implement appropriate safeguards to protect electronic protected health information (ePHI). For security incident procedures, organizations should:

1. Establish and document policies specific to security incident procedures
2. Implement technical and procedural controls
3. Train workforce members on their responsibilities
4. Conduct periodic risk assessments addressing security incident procedures
5. Maintain documentation of compliance efforts

Under 45 CFR 164.308, this is a administrative safeguards requirement that applies to all covered entities and business associates that create, receive, maintain, or transmit ePHI.

- Identify and develop 'security standards for open systems - Specify a key management system that supports these security standards - Encourage the development of interoperable equipment

The SDNS architecture, and its associated specifications, were developed as a cooperative project between government and industry. The project was sponsored by the National Security Agency, and supported by the National Institute of Standards and Technology (formerly the National Bureau of Standards) and the Defense Communications Agency. Twelve leading U.S. companies in computers and telecommunications made significant contributions of their technical talents and development resources. The combined efforts of these organizations produced the basis for improved security technology, interoperable security standards, and costeffective security for computers and telecommunications. This document provides the framework for the SDNS Security Protocol at layer three (SP3). This document is being circulated for comment and approval. It is subject to change during the development phase of SDNS.

December 31, 2017, was the DoD deadline for contractors to implement, as applicable, the cybersecurity protection requirements set forth in NIST SP 800-171 Re2, Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations, in accordance with requirements of DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting. NIST SP 800-171A Jun2018 states, ·For the CUI security requirements in NIST Special Publication 800-171 Rev 2, nonfederal organizations describe in a system security plan, how the specified requirements are met or how organizations plan to meet the requirements.· [61] The NIST process provides contractors with a tool to assess their security posture and decide if or when to mitigate the risks based upon the organizational risk tolerance. When the DoD implemented the NIST SP 800-171 requirements with a not-later-than date of December 2017, the policy intent was to permit contractors some flexibility to remediate lagging NIST requirements, and document them in plans of action, and resolve those deficiencies within a reasonable period. An unintended consequence of this flexibility was that some contractors far exceeded the intention to secure systems that must adequately safeguard CUI in a timely manner and instead created open-ended plans of action with undefined closure dates. The effect was to delay full compliance with safeguarding requirements for

years. As a result, the DoD's implementation of the NIST SP 800-171 requirements, as mandated by 32 CFR part 2002, has not been fully effective or validated. This necessitates implementation of the CMMC Program to enforce a finite timeline for full compliance of contractual requirements. Findings from DoD Inspector General report (DODIG-2019-105 -Audit of Protection of DoD Controlled Unclassified Information on Contractor-Owned Networks and Systems-) indicated that DoD contractors did not consistently implement mandated system security requirements for safeguarding CUI and recommended that DoD take steps to assess a contractor's ability to protect this information. CMMC adds an assessment requirement to verify defense contractors and subcontractors have implemented the applicable security requirements prior to award. CMMC also adds requirements at each CMMC level for contractors and subcontractors to affirm initial compliance with the specified CMMC security requirements and provide annual affirmations thereafter. (b) Comprehensive Implementation of Cybersecurity Requirements Although the security requirements in NIST SP 800-171 R2 address a range of threats, they do not sufficiently address Advanced Persistent Threats (APTs). An APT is an adversary that possesses sophisticated levels of expertise and significant resources, which allow it to create opportunities to achieve its objectives by using multiple attack vectors (e.g.,

This is not to suggest that all usability research is conducted in this manner (nor should it be, as different study designs and sample sizes are more appropriate to answer different research questions), nor is this to suggest that all usability researchers have the background and training to conduct such studies (just as there are many security specializations, so too are there many specializations in usability and human factors), but merely to give an example of experimental methodology with which other fields may already be more familiar. The final point is this: no matter the sample size, it is both possible and necessary to conduct human subjects research with rigor. We urge both usability and security practitioners to examine each other's work through the lens of experimental design and be critical consumers of others' research; many of the same principles apply regardless of whether one is measuring human behavior, system behavior, or combined human-system performance.

Cryptographic Module Validation Program; CMVP; FIPS 140 testing; FIPS 140-3; ISO/IEC 19790; ISO/IEC 24759; sensitive security parameter establishment methods; sensitive security parameter generation; testing requirement; vendor evidence; vendor documentation. This document is intended for use by vendors, testing labs, and the CMVP.

Control ID-19: ams Administration for the Safety and Security Review of Waterfront Import/Export Liquefied Natural Gas Facilities. Available at: - [14] Mahn A, Marron J, Quinn S, Topper D (2021) Getting Started with the NIST Cybersecurity Framework: A Quick Start Guide. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 1271. <https://doi.org/10.6028/NIST.SP.1271> - [15] Stouffer K, Pease M, Tang C, Zimmerman T, Pillitteri V, Lightman, S (2022) Guide to Operational Technology (OT) Security. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-82r3 ipd (initial public draft). - [16] National Cybersecurity Federally Funded Research and Development Center (NCF) operated by MITRE supports NIST's National Cybersecurity Center of Excellence. Available at - [17] Long J, Thompson M, Ayala M, Beebe T, Belisle M, Girdner A, Casey C, Collins C, Tran H, Herriott A, Yates C, Newhouse B, El-Najjar K, Wynn D, Northrip D, Davis P, Shires D, Weitzel D, Fitzpatrick D, Wallace C, Savoury R, Mann D, DeMoura D (2021) Marine Transportation Systems LNG Cybersecurity Industry Profile Online Workshop 1, The MITRE Corporation, May 13, 2021 (10:00 a.m. to 12:30 p.m. EDT). - [18] Long J, Thompson M, Ayala M, Beebe T, Casey C, Collins C, Tran H, Herriott A, Newhouse B, Wynn J, Northrip D, Weitzel D, Fitzpatrick D, Savoury R, Mann D, Alvarado O, Brule J, Pace K, Byrne T, Bloom C, Yates C, Davis P, Yamben W, Philibert R, El-Najjar K, DeMoura D (2021) Marine Transportation Systems LNG Cybersecurity Industry Profile Online Workshop 2, The MITRE Corporation, May 20, 2021 (10:00 a.m. to 12:30 p.m. EDT).

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System [Docket Number DARS-2025-0006; OMB Control Number 0704-0478] AGENCY: Defense Acquisition Regulations System; Department of Defense (DoD). ACTION: Notice and request for comments regarding a proposed

extension of an approved information collection requirement. SUMMARY: In compliance with the Paperwork Reduction Act of 1995, DoD announces the proposed extension of a public information collection requirement and seeks public comment on the provisions thereof. DoD invites comments on: whether the proposed collection of information is necessary for the proper performance of the functions of DoD, including whether the information will have practical utility; the accuracy of DoD's estimate of the burden of the proposed information collection; ways to enhance the quality, utility, and clarity of the information to be collected; and ways to minimize the burden of the information collection on respondents, including the use of automated collection techniques or other forms of information technology. The Office of Management and Budget (OMB) has approved this information collection for use through October 31, 2025. DoD proposes that OMB approve an extension of the information collection requirement, to expire three years after the approval date. DATES: DoD will consider all comments received by August 5, 2025. ADDRESSES: You may submit comments, identified by OMB Control Number 0704-0478, using either of the following methods: · Federal eRulemaking Portal: <https://www.regulations.gov> . Follow the instructions for submitting comments. · Email: osd.dfars@mail.mil . Include OMB Control Number 0704-0478 in the subject line of the message. Comments received generally will be posted without change to <https://www.regulations.gov> , including any personal information provided. FOR FURTHER INFORMATION CONTACT: Ms. Heather Kitchens, at 571-296-7152. SUPPLEMENTARY INFORMATION: Title and OMB Number: Safeguarding Covered Defense Information, Cyber (printed page 24197) Incident Reporting, and Cloud Computing; OMB Control Number 0704-0478. Affected Public: Businesses or other for-profit and not-for-profit institutions. Respondent's Obligation: Required to obtain or retain benefits. Frequency: On occasion. Number of Respondents: 1,971. Responses per Respondent: 8.2, approximately. Annual Responses: 16,233. Average Burden per Response: 0.42 hour. Annual Burden Hours: 6,770. Needs and Uses:

(F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (32) System identifier and name. A0608-18 DASG, Army Family Advocacy Program Files. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigative material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Therefore, portions of the system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) or (k) (5) from subsections 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because the requirements in those subsections are inapplicable to the extent that portions of this system of records may be exempt from subsection (d), concerning individual access.

(1) Classified information in every Army system of records. Before denying any individual access to classified information, the Access and Amendment Refusal Authority must make sure that it was properly classified under the standards of Executive Orders 11652, 12065, or 12958 and that it must remain so in the interest of national defense or foreign policy (5 U.S.C. 552a(k)(1)). (2) Investigatory material compiled for law enforcement purposes (other than material within the scope

of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if this information has been used to deny someone a right, privilege or benefit to which the individual is entitled by Federal law, or for which an individual would otherwise be eligible as a result of the maintenance of the information, it must be released, unless doing so would reveal the identity of a confidential source. Note 1 to paragraph (d)(2). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (3) Records maintained in connection with providing protective services to the President of the United States or other individuals protected pursuant to Title 18 U.S.C., section 3056 (5 U.S.C. 552a(k)(3)). (4) Records maintained solely for statistical research or program evaluation purposes and which are not used to make decisions on the rights, benefits, or entitlements of individuals, except for census records which may be disclosed under Title 13 U.S.C., section 8 (5 U.S.C. 552a(k)(4)). (5) Investigatory material compiled solely to determine suitability, eligibility, or qualifications for Federal service, Federal contracts, or access to classified information. This information may be withheld only to the extent that disclosure would reveal the identity of a confidential source (5 U.S.C. 552a(k)(5)). (6) Testing or examination material used solely to determine if a person is qualified for appointment or promotion in the Federal service. This information may be withheld only if disclosure would compromise the objectivity or fairness of the examination process (5 U.S.C. 552a(k)(6)). (7) Evaluation material used solely to determine promotion potential in the Armed Forces. Information may be withheld, but only to the extent that disclosure would reveal the identity of a confidential source (5 U.S.C. 552a(k)(7)). (e) Procedures. When a system manager seeks an exemption for a system of records, the following information will be furnished to the Chief Information Officer, 107 Army Pentagon, Room 3E608, Washington, DC 20310-0107; applicable system notice, exemptions sought, and justification. After appropriate staffing and approval by the Secretary of the Army, a proposed rule will be published in the Federal Register , followed by a final rule 60 days later. No exemption may be invoked until these steps have been completed.

DFARS 252.204-7008 (Compliance with Safeguarding CDI Controls) Requires offerors to represent that they will implement NIST SP 800-171 security requirements. Flow-down requirements: DFARS 252.204-7008 includes flow-down provisions requiring prime contractors to include the clause in subcontracts where CUI will be processed, stored, or transmitted. Subcontractors must meet the same security requirements as the prime.

). Section 307 of the Bioterrorism Act amends the FD&C Act by adding section 801(m) to the FD&C Act. Section 801(m) of the FD&C Act refers to an ‘article of food.’ However, the legislative history of section 307 of the Bioterrorism Act indicates that packaging materials are not subject to section 307, and can be read to imply that Congress was not relying on the definition of food in section 201(f) of the FD&C Act, thereby giving rise to ambiguity about which definition of ‘food’ applies to section 307 of the Bioterrorism Act. FDA also considered the meaning of ‘food’ in section 303 of the Bioterrorism Act, governing administrative detention, and concluded that it is ambiguous. FDA determined that use of the definition of ‘food’ in section 201(f) of the FD&C Act is consistent with the language of section 303 of the Bioterrorism Act. Section 303 repeatedly uses the term ‘food’ without adjectives, except for a reference to ‘perishable foods,’ which is not used to limit the reach of the section. FDA also determined that use of the definition of ‘food’ in section 201(f) of the FD&C Act is consistent with the use of the term in judicial enforcement actions (e.g., seizures and injunctions) that may be instituted under administrative detention. The ambiguity surrounding Congress’s use of ‘food’ in sections 303, 305, 306, and 307 of the Bioterrorism Act, coupled with the lack of a definition of the term in the Bioterrorism Act, support a conclusion that the meaning of ‘food’ in the Bioterrorism Act is ambiguous. Having concluded that the meaning of ‘food’ in the Bioterrorism Act and in section 306 of the Bioterrorism Act in particular is ambiguous, FDA has considered how to define the term to achieve a ‘permissible construction’ of the records establishment and maintenance provisions. *Chevron, USA, Inc. v. NRDC, Inc.*, supra at 843. In conducting this Chevron step two analysis, the agency has considered the same information it evaluated at step one of the analysis. *Bell Atlantic Telephone Co. v. FCC*, 131 F. 3d 1044, 1049 (D.C. Cir. 1997); *Chevron U.S.A., Inc. v. FERC*, 193 F. Supp. 2d 54, 68 (D.D.C. 2002). FDA has determined that it is permissible, for purposes of the records establishment and maintenance provisions, to use the definition of ‘food’ in section 201(f) of the FD&C Act.

This definition is based on the definition of ‘general support system’ or ‘system’ in the appendix to the 1996 version of OMB Circular A-130, Security of Federal Automated Information Systems. [

995] We considered proposing to remove the phrase “under the same direct management control” as a potential way to clarify the application of the definition to cloud-based computing. Cloud computing applications play an important role in health care today. For example, many health care providers have implemented cloud-based electronic health records (EHRs) and practice management systems. These applications are used to create, receive, maintain, and transmit ePHI, and as such, should be included as components of a covered entity's relevant electronic information system, a term which is based upon the term “information system.” After careful consideration, we have decided to retain the phrase “under the same direct (printed page 1006) management control” and instead clarify in the preamble how the definition of “information system” applies in cloud computing environments. The Department also requests comment on the definition of “information system” and the extent of control a regulated entity has with respect to applications in cloud computing environments. We also considered proposing to adopt the definition of “information system” in the Paperwork Reduction Act of 1995 (PRA) and the current operative version of OMB Circular A-130. [996] The PRA and OMB Circular A-130 define “information system” as “a discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.” The Department declined to adopt this definition because the existing definition in the Security Rule based on the definition of “system” in the 1996 version of OMB Circular A-130 more accurately reflects the typical components of an information system and the full extent of resources that are addressed by the Security Rule. Additionally, the definition of “information system” in the PRA and current operative version of OMB Circular A-130 contains some terms that are defined by the HIPAA Rules and some that are not. As a result, adopting this definition would require the Department to propose definitions to such additional terms and to ensure that the manner in which the terms with existing definitions are used is consistent with those existing definitions, and we are concerned that such change could cause significant confusion for regulated entities. We do not believe that either of the alternative definitions considered would have generated a quantifiable change in costs because the alternatives would be clarifications to existing requirements and would not have changed the scope of the Security Rule's applicability. Exception From Multi-Factor Authentication (MFA) Requirement

Most workshop participants agreed that manufacturers of IoT devices currently lack market incentives to prioritize cybersecurity as a concern when designing, marketing, and supporting their products. Some counterexamples were presented in which informed customers do recognize the advantages of enhanced security. This suggests that enhanced cybersecurity could demonstrably be a market advantage if it is emphasized. Workshop poll results showed strong support (71 %) for government mandates as a mechanism for enhancing IoT cybersecurity (poll #4), and general agreement (55 %) that developers of IoT devices currently lack appropriate incentives to secure their products (poll #2). Participants supported a mixture of regulatory guidance, customer education, supply chain pressures, and other considerations to create the economic incentives to shift the overall IoT device market toward enhanced cybersecurity.

full-time employees, and that are located in the same general physical location as farms that sell unprocessed food grown or raised on those farms. The comments note that the exclusion does not apply to processed foods, even if they are sold directly to the consumers from the retail facility in the same general location as the farm, unless all the ingredients in that processed food were grown or raised on that farm. Consequently, persons handling processed foods, such as baked goods, jams, jellies, maple syrup, and “processed” items such as hams and sausages from animals grown and processed into meat products on the farm would fall under the provisions of the final rule. Also, any persons handling products that were “imported” from off the farm would be subject to the final rule. The processed food provision is a burden for those involved in roadside stands that operate outside of the normal seasonal harvest period or sell processed foods. They could not purchase goods from neighbors or bring in goods from other areas under the exemption or include ingredients from a nonfarm source. The comment asks that this limitation affecting farm markets be removed from the final rule. (Response) FDA has changed the exclusion in proposed § 1.327(d)(2) and has now provided an exclusion for all retail food establishments that employ 10 or fewer full-time equivalent employees from all of the regulations in this final rule, except the record access provisions for existing records under §§ 1.361 and 1.363, regardless of whether the food being sold is processed or unprocessed. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) 7. Persons Under the Exclusive Jurisdiction of USDA (Comment 54) One comment states that proposed §§ 1.327 and 1.328 distinguish between those foods that will be subject to the requirements of the final rule, and those foods that will be exempt. In doing so, the

proposed rule refers to other federal statutes (e.g., the Federal Meat Inspection Act, the Poultry Products Inspection Act, and the Egg Products Inspection Act), as a means to provide the regulated community with the relevant details as to whether and when their conduct will come within the scope of the regulations being proposed. Although statutory references such as these may suffice to inform farms, food manufacturers, restaurants, and other food-related facilities that deal with these statutes on a daily basis whether and when they will be subject to FDA's final rule, that is clearly not the case with motor carriers. Therefore, the comment states that FDA should explain what food is subject to the final rule in layman's language to avoid any confusion. The comment further recommends that FDA attach a list of the applicable or the exempted foods as an appendix to the final rule.

Government procurement Michele P. Peterson, Editor, Defense Acquisition Regulations System. Therefore, 48 CFR part 252 is amended as follows: PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 1. The authority citation for 48 CFR part 252 continues to read as follows: Authority: 41 U.S.C. 421 and 48 CFR Chapter 1 . 2. Section 252.204-7004 is amended as follows: a. By revising the section heading, clause title, and clause date; and b. In paragraph (a), by revising the definition of "Registered in the CCR database" to read as follows: 252.204-7004 Alternate A, Central Contractor Registration. ALTERNATE A, CENTRAL CONTRACTOR REGISTRATION (SEP 2007) * * * * (a) * * * "Registered in the CCR database" means that: (1) The Contractor has entered all mandatory information, including the DUNS number or the DUNS+4 number, into the CCR database; (2) The Contractor's CAGE code is in the CCR database; and (3) The Government has validated all mandatory data fields, to include validation of the Taxpayer Identification Number (TIN) with the Internal Revenue Service, and has marked the records "Active." The Contractor will be required to provide consent for TIN validation to the Government as part of the CCR registration process. [FR Doc. E7-17433 Filed 9-5-07; 8:45 am] BILLING CODE 5001-08-P

Commissioning records are maintained in accordance with FDA's Records Control Schedule and the applicable General Records Schedule and disposition schedules approved by NARA. Commissioning records fall under NARA approved citation N1-088-09-02 for Commissioning Documents, the Nationwide List of FDA Commissions, and Summary Reports of FDA Commissions. Commissioning documents are deleted/destroyed 5 years after the end of the fiscal year in which a commission is revoked or expires. Records within the nationwide list of FDA commissions are deleted/destroyed 5 years after the fiscal year when they become obsolete or are superseded. Summary reports of FDA commissions are deleted/destroyed after the nationwide list of FDA Commissions has been updated. L. System Manager(s) and Address Ryan Cates, Food and Drug Administration, Office of Partnerships, Element Building, 12420 Parklawn Dr., Rockville, MD 20857, 301-796-5390, FAX: 301-827-3588, OP-ORA@fda.hhs.gov . M. Notification Procedure In accordance with 21 CFR part 21 Subpart D , an individual may submit a request to the FDA Privacy Act Coordinator, with a notarized signature, to confirm whether records exist about him or her. Requests should be directed to the FDA Privacy Act Coordinator, Division of Freedom of Information, 12420 Parklawn Dr., ELEM-1029, Rockville, MD 20857. An individual requesting notification via mail should certify in his or her request that he or she is the individual who he or she claims to be and that he or she understands that the knowing and willful request for or acquisition of a record pertaining to an individual under false pretenses is a criminal offense under the Privacy Act subject to a \$5,000 fine, and indicate on the envelope and in a prominent manner in the request letter that he or she is making a "Privacy Act Request." Additional details regarding notification request procedures appear in 21 CFR part 21, subpart D . A commission holder may also request an opportunity to review his or her own file by contacting the appropriate Regional Food and Drug Director. N. Record Access Procedures Procedures are the same as above, in the Notification Procedure section. Requesters should also reasonably specify the record contents being sought. Some records may be exempt from access under 5 U.S.C. 552a(d)(5) , if they are "compiled in reasonable anticipation of a civil action or proceeding." If access to requested records is denied, the requester may appeal the denial to the FDA Commissioner. Additional details regarding record access procedures and identity verification requirements appear in 21 CFR part 21, subpart D . O. Contesting Record Procedures

(A) From subsections (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d), because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the

subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (25) System identifier and name. A0380-67 DAMI, Personnel Security Clearance Information Files. (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958, as implemented by DoD 5200.1-R, may be exempt pursuant to 5 U.S.C. 552a(k)(1). (B) Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (C) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (D) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(1)

(4) Amendments to Component rules are submitted like the basic rules. (5) The DPO submits the rules and amendments thereto to the Federal Register for publication. (e) Submission of exemption rules for publication. (1) No system of records within the Department of Defense shall be considered exempt from any provision of this part until the exemption and the exemption rule for the system has been published as a final rule in the Federal Register. (2) Submit exemption rules in proper format to the DPO. All exemption rules are coordinated with the DoD Office of General Counsel. After coordination, the DPO shall submit the rules to the Federal Register for publication. (3) Exemption rules require publication both as proposed rules and final rules (see AI 102). (4) § 310.31(b) discusses the content of an exemption rule. (5) Submit amendments to exemption rules in the same manner used for establishing these rules. (f) Submission of system notices for publication. (1) System notices are not subject to formal rulemaking procedures. However, the Privacy Act (5 U.S.C. 552a) requires a system notice be published in the Federal Register of the existence and character of a new or altered system of records. Until publication of the notice, DoD Components shall not begin to operate the system of records (i.e., collect and use the information). The notice procedures require: (i) The system notice describes what kinds of records are in the system, on whom they are maintained, what uses are made of the records, and how an individual may access, or contest, the records contained in the system. (ii) The public be given 30 days to comment on any proposed routine uses before any disclosures are made pursuant to the routine use; and (iii) The notice contain the date on which the system shall become effective. (2) Submit system notices to the DPO in the Federal Register format (see AI 102 and Appendix E to this part). The DPO transmits the notices to the Federal Register for publication. (3) § 310.32 discusses the specific elements required in a system notice. § 310.31 Exemption rules. (a) General procedures. Subpart F of this part provides the general guidance for establishing exemptions for systems of records. (b) Contents of exemption rules. (1) Each exemption rule submitted for publication must contain the following: (i) The record system identifier and title of the system for which the exemption is claimed. (See § 310.32(b) and (c)); (ii) The specific sections of the Privacy Act under which the exemption for the system is claimed (for example, 5 U.S.C. 552a(j)(2), 5 U.S.C. 552a(k)(3); or 5 U.S.C. 552a(k)(7); (iii) The specific sections of the Privacy Act from which the system is to be exempted (for example, 5 U.S.C. 552a(c)(3), or 5 U.S.C. 552a(d)(l)-(5)) (see Appendix D)); and (iv) The specific reasons why an exemption is being claimed from each section of the Act identified.

DoD will also consider comments from small entities concerning the existing regulations in subparts affected by this rule in accordance with 5 U.S.C. 610. Interested parties must submit such comments separately and should cite 5 U.S.C. 610 (DFARS Case 2018-D043), in correspondence. XIII. Paperwork Reduction Act This rule affects the information collection requirements at DFARS subpart 232.10 (and associated clauses at DFARS 252.232-7012 and 252.232-7013, currently approved under OMB Control Number 0704-0359, DFARS Part 232, Contract Financing. The impact, however, is negligible, because only the last three lines of the table are deleted, which do not impose the predominance of the burden. This rule also adds a new information collection requirement that requires the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). Accordingly, DoD has submitted a request for approval of a new information collection requirement concerning the provision at 252.232-70XX, Performance-Based Payments-Representation to the Office of Management and Budget. A. Public reporting burden for this collection of information is estimated to average 0.1 hours per response, including the time for reviewing instructions, searching existing data sources, gathering and maintaining the data needed, and completing and reviewing the collection of information. The annual reporting burden estimated as follows: Respondents: 144. Responses per respondent: 1. Total annual responses: 144. Preparation hours per response: 0.1 hours. Total response Burden Hours: 14.4. B. Request for Comments Regarding Paperwork Burden. Written comments and recommendations on the proposed information collection, including suggestions for reducing this burden, should be sent to Ms. Jasmeet Seehra at the Office of Management and Budget, Desk Officer for DoD, Room 10236, New Executive Office Building, Washington, DC 20503, or email Jasmeet_K_Seehra@omb.eop.gov, with a copy to the Defense Acquisition Regulations System, Attn: Ms. Amy G. Williams, OUSD(A&S)DPC/DARS, Room 3B941, 3060 Defense Pentagon, Washington, DC 20301-3060. Comments can be received from 30 to 60 days after the date of this notice, but comments to OMB will be most useful if received by OMB within 30 days after the date of this notice. Public comments are particularly invited on: Whether this collection of information is necessary for the proper performance of functions of the DFARS, and will have practical utility; whether our estimate of the public burden of this collection of information is accurate, and based on valid assumptions and methodology; ways to enhance the quality, utility, and clarity of the information to be collected; and ways in which we can minimize the burden of the collection of information on those who are to respond, through the use of appropriate technological collection techniques or other forms of information technology.

I factors, including the expansion of packet size, ciphering latency, and a lack of QoS urgency in the cryptographic engine itself can cause an excessive amount of latency in the VOIP packet delivery. This leads to degraded voice quality, so once again there is a tradeoff between security and voice quality, and a need for speed. Fortunately, the difficulties are not insurmountable. NIST-sponsored testing [29] has shown that IPsec can be incorporated into a SIP network with roughly a three-second additional delay in call setup times, an acceptable delay for many applications. This section explains the issues involved in successfully incorporating IPsec encryption into VOIP services.

- (1) Data Integrity, - (2) Data Confidentiality, - (3) Data Origination Authentication, and - (4) Access Control. The SP4 standard identifies other security functions on which it depends. These functions include key management, security management, and cryptography. Key management is needed to establish and maintain keying material used by SP4; security management is needed for event reporting and auditing; and cryptography (i.e., employment of specific cryptographic algorithms) is needed to support Data Integrity, Data Confidentiality, and Authentication services. These functions are normally collocated in an end-system, with an SP4 entity. computer system operating environment. The objective of the security evaluation is to perform a technical assessment of the trust properties. Three general security issues that must be addressed are: the confidentiality of the data, the integrity of the data and the system, and the availability of service. The goal or main requirement is to assure that the system behaves according to an organization's security requirements that, in turn, reflect the defined security policy of the organization. To guarantee that this requirement is met, the security functionality of an implementation must work correctly and effectively.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current

requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. Organizations that are planning to use products that use the Bluetooth 4.0, 4.1, or 4.2 technologies should carefully consider the security implications. The 4.0 specification was released in mid-2010, and the 4.2 specification was released in December 2014. At the time of this writing, one significant security vulnerability related to 4.0 has been discovered (see Table 4-1 below). Additionally, few products that support the 4.2 specification are currently available for evaluation. As more compliant products become available, additional vulnerabilities will possibly be discovered, and additional recommendations will be needed for effectively securing Bluetooth low energy devices. Organizations planning to deploy Bluetooth low energy devices should carefully monitor developments involving new vulnerabilities, threats, and additional security control recommendations.

In March 2021, the Department initiated an internal assessment of CMMC 1.0 implementation that was informed by more than 850 public comments in response to the interim DFARS rule. This comprehensive, programmatic assessment of CMMC engaged cybersecurity and acquisition leaders within DoD to refine policy and program implementation. This review resulted in CMMC 2.0, which updates the program structure and the requirements to streamline and improve implementation of the CMMC program. Way Forward The changes reflected in the CMMC 2.0 framework will be implemented through the rulemaking process. DoD will pursue rulemaking in both: (1) Title 32 of the Code of Federal Regulations (CFR); and, (2) title 48 CFR, to establish CMMC 2.0 program requirements and implement any needed changes to the CMMC program content in 48 CFR. Both rules will have public comment periods. Publication of title 32 and title 48 CFR rules will implement DoD's requirements for the updated CMMC version 2.0, which include various modifications from CMMC 1.0. These modifications include: Eliminating levels 2 and 4, and renaming the remaining three levels in CMMC 2.0 as follows: Level 1 (Foundational) will remain the same as CMMC 1.0 Level 1; Level 2 (Advanced) will be similar to CMMC 1.0 Level 3; Level 3 (Expert) will be similar to CMMC 1.0 Level 5. Removing CMMC-unique practices and all maturity processes from all levels; For CMMC Level 1 (Foundational), allowing annual self-assessments with an annual affirmation by DIB company leadership; Bifurcating CMMC Level 2 (Advanced) assessment requirements: Prioritized acquisitions involving CUI will require an independent third party assessment; Non-prioritized acquisitions involving CUI will require an annual self-assessment and annual company affirmation; For CMMC Level 3 (Expert), requiring Government-led assessments. Developing a time-bound and enforceable Plan of Action and Milestone process; and, Developing a selective, time-bound waiver process, if needed and approved. The title 32 CFR rulemaking for CMMC 2.0 will be followed by additional title 48 CFR rulemaking, as needed, to implement any needed changes to the CMMC program content in 48 CFR. DoD will work through the rulemaking processes as expeditiously as possible. Until the CMMC 2.0 changes become effective through both the title 32 CFR and title 48 CFR rulemaking processes, the Department will suspend the CMMC Piloting efforts and will not approve inclusion of a CMMC requirement in DoD solicitations. The CMMC 2.0 program requirements will not be mandatory until the title 32 CFR rulemaking is complete, and the CMMC program requirements have been implemented as needed into acquisition regulation through title 48 rulemaking. Dated: November 8, 2021. Patricia L. Toppings, OSD Federal Register Liaison Officer, Department of Defense. [FR Doc. 2021-24880 Filed 11-16-21; 8:45 am] BILLING CODE 5001-06-P

3.5.1 Authorization Models... 3.5.1 Authorization Models... 3.5.1 Authorization Models The following subsections describe the authorization models most relevant to access management in a SOA, namely role-based, attribute-based, policy-based, and risk-adaptive access control.

) Contractor access to proscribed information will not be granted without the approval of the agency with control jurisdiction (i.e., National Security Agency (NSA) for COMSEC, whether the COMSEC is proscribed information or not; the Office of the Director of National Intelligence (ODNI) for SCI; and the Department of Energy (DOE) for RD in accordance with its policies). (4) In accordance with 32 CFR, part 2004 and the procedures in paragraph (b)(5) of this section, GCAs will forward a request for concurrence to NSA, ODNI, or DOE when a proposed NID involves access to COMSEC, SCI, or RD, respectively, within 30 calendar days of DSS advisement of the NID requirement. NSA, ODNI, and DOE, as appropriate, will then have 30 calendar days to render a decision. (D) VTA or PA. These FOCI negotiation agreements may be used when a foreign interest effectively owns or controls a company or corporate family. Under a VTA, PA and associated documentation, the foreign owner relinquishes most rights associated with ownership of the company to cleared U.S. citizens approved

by DSS. Both FOCI agreements can effectively negate foreign ownership and control; therefore, neither agreement imposes any restrictions on the company's eligibility to have access to classified information or to compete for classified contracts including contracts with proscribed information. Both FOCI agreements can also effectively negate foreign government control (see paragraph (b)(11) of this section which provides guidance and requirements regarding foreign government ownership or control, including with respect to 10 U.S.C. 2536 , Award of Certain Contracts to Entities Controlled by a Foreign Government Prohibition (available at <http://www.gpo.gov/fdsys/granule/USCODE-2010-title10/USCODE-2010-title10-subtitleA-partIV-chap148-subchapV-sec2536/content-detail.html>)). DSS retains the authority to deny a proposed VTA or PA. (iv) When DSS implements a FOCI mitigation or negation agreement at a contractor, the agreement may specify that the entire agreement, or that particular provisions of the agreement (e.g., the provisions restricting unauthorized access to classified information and unclassified export-controlled information and the provisions of the visitation policy) will apply to and will be made binding upon all present and future subsidiaries of the company. If a subsidiary requires and is eligible for an FCL at the TS level, the company executing the FOCI mitigation agreement and any intermediate parents must be formally excluded from TS access unless they have their own requirement and are otherwise eligible for TS access.

emphasizes the importance of retrospective analysis of rules with its 'look back' requirement, which states that 'within 120 days of the date of this order, each agency shall develop . . . a preliminary plan.' The plans should 'facilitate the periodic review of rules that may be outmoded, ineffective, insufficient, or excessively burdensome, and to modify, streamline, expand, or repeal them in accordance with what has been learned.' This rule updates policy and procedures for industry that are more than 20 years old. DoD's full plan and updates can be accessed at: <http://exchange.regulations.gov/exchange/topic/eo-13563> . Justification for Interim Final Rule Without this rule, the Components face an elevated risk of unauthorized disclosure of classified information to foreign interests resulting in potential economic losses or damage to U.S. national security. There is such an increased probability of unauthorized disclosure of classified information because the owner of a U.S. company has direct authority over all aspects of his company (e.g., who gets paid, what contracts, including classified contracts are pursued, and access to information/programs that those contracts include. If the U.S. company has a foreign owner and is awarded a contract requiring access to classified information, these procedures provide actions for the USG to take to keep that foreign owner from having direct authority over the disclosure of and access to classified information. If there are no procedures as set forth in this rule to evaluate and determine how to negate or mitigate the foreign ownership, there will be nothing to prevent unauthorized disclosures of classified information since the foreign owner will have unfettered control of the U.S. company. This proposed rule provides the baseline requirements for the USG to evaluate the foreign owner's rights and determine whether those rights can be mitigated to effectively protect classified information and preclude its unauthorized disclosure. Depending upon what a foreign-owned U.S. company is working on, unauthorized disclosure of classified information could have an adverse impact on national security. This rule allows fair and open competition among U.S. companies, including foreign-owned U.S. companies, who are vying for the opportunity to provide products and services to the Components when access to classified information is required. Also, without this rule, Components will not have the ability to consider innovative technologies developed by foreign-owned U.S. companies due to concerns with awarding a classified contract without a uniform process to assess and effectively mitigate or negate existing FOCI. Finally, the lack of a formal, uniform process has created significant delay in the completion of National Interest Determinations (NIDs) for foreign-owned U.S. contractors. These delays increase the costs to Components by preventing contract performance when access to classified information is required.

The Director of Defense Procurement is proposing to amend the Defense Federal Acquisition Regulation Supplement (DFARS) to add a requirement for contractor employees that are cleared for access to certain classified information to attest orally that they will comply with the security requirements associated with the information.

The Offeror shall appropriately identify information the Offeror owns and provides to the Government, which is contractor bid or proposal information, contractor-attributional information, or Offeror proprietary business information. The Government will determine in accordance with agency procedures whether the information provided by the Offeror is CUI or entitled to other protections (e.g., contractor-attributional information associated with a CUI incident). (d) Unmarked CUI or

mismarked CUI. The Offeror should notify the Contracting Officer within 8 hours of discovery if the Offeror discovers any CUI that is not marked, not properly marked, not identified on the SF XXX, or is involved in a suspected or confirmed CUI incident. The Offeror should take action to appropriately safeguard any information the Offeror believes is CUI that is not identified in the SF XXX or is not marked or properly marked as required in the SF XXX until a Contracting Officer makes a determination. (End of provision) 52.204-XX Controlled Unclassified Information. As prescribed in 4.403-7(b), insert the following clause: Controlled Unclassified Information (DATE) (a) Identifying controlled unclassified information. The SF XXX, Controlled Unclassified Information, that is incorporated into this contract identifies what controlled unclassified information (CUI) is involved in the contract. The Contractor is required to safeguard only the CUI that is identified in the SF XXX. However, see paragraph (c)(2) of this clause. (b) Definitions. As used in this clause: Adequate security means security protections commensurate with the risk of harm resulting from unauthorized access, use, disclosure, disruption, modification, or destruction of information. Contractor-attributional information means information that identifies the Contractor or its employees directly or identifies them indirectly by grouping information that can be traced back to the Contractor (e.g., program description or facility locations). Contractor bid or proposal information means any of the following information submitted to a Federal agency as part of or in connection with a bid or proposal to enter into a Federal agency procurement contract, if that information has not been previously made available to the public or disclosed publicly: (1) Cost or pricing data as defined by 10 U.S.C. 3701(1) , with respect to procurements subject to that section, and 41 U.S.C. 3501(a)(2) , with respect to procurements subject to that section. (2) Indirect costs and direct labor rates. (3) Proprietary information about manufacturing processes, operations, or techniques marked by the Contractor in accordance with applicable law or regulation. (4) Information marked by the Contractor as Contractor bid or proposal information in accordance with applicable law or regulation. (5) Information marked in accordance with 52.215-1(e). Controlled unclassified information (CUI)

Control RC-725: st of the other nodes that they want to connect with) or via smart contracts onchain. Changes to the list of validators may then be administered through onchain voting by administrators. Alternatively, an IDMS may form an open protocol and/or ecosystem that can be used and integrated by anyone. It can be a general purpose ecosystem or a more application-specific one (e.g., credit scoring with Bloom Protocol [60]). Furthermore, an IDMS can involve users authenticating at the application level or at the ecosystem level such as in Blockstack [49]. The latter differs from traditional single sign-on identity management in that identifier origination, credential issuance, and presentation disclosure are not necessarily controlled by a single entity. In some systems, tokens may be utilized to design an incentive structure and boost certain desired behaviors from the participants (e.g., through earning rewards) to facilitate ecosystem coordination, self-sustainability, and growth (can be based on various game theory techniques). The incentive structure can be extended to built-in monetization schemes to buy and sell services. More specifically, they may be coded directly as part of the functions that implement actions, such as credential issuance and presentation disclosure. 9 A second layer protocol can be used as an access control mechanism for permissioned blockchains. For example, the ChainAnchor scheme [59] offers this while allowing users to transact pseudonymously and maintain transaction unlinkability: users can selectively disclose their transactions if asked to (e.g., for regulatory purposes) without revealing their other transactions. This scheme makes use of the 'Enhanced Privacy ID' zero-knowledge protocol. ## Internal Rules Management : Every system has rules that dictate how participants interact with a given system.

Two comments asked how many current contract awardees had received notification or identification of CUI to be provided in performance of their contracts, and asked which CMMC level would theoretically apply to those contracts. Another asked the DoD to provide DIBCAC assessment results data as a more relevant justification for the CMMC program than the 2019 DoDIG report on DIB Cybersecurity. Response: DoD's response to the referenced GAO and DoD IG reports are beyond the scope of this rule. Likewise, the DoD does not comment on analysis methods supporting the DoD IG's conclusions. Publishing DIBCAC assessments results is also beyond the scope of this rule, as are CMMC Program effectiveness metrics and return on investment calculations. The DoD is establishing CMMC assessment requirements as part of a comprehensive effort to verify that underlying information security requirements are met, as required, for all contractor owned information systems that process, store, or transmit CUI or FCI in the performance of a DoD Contract. DoD's calculation of ROI for the security controls that CMMC will assess, and cost elasticity of the DIB are also beyond the scope of

this rule. 7. Phased Implementation of the Program Comment: Many comments asked for additional explanation of DoD's expected start and progression through phases of the CMMC implementation plan. Several asked that the phase-in plan be extended. One commenter asked whether contracts that would otherwise be associated with CMMC Level 3 would include a CMMC Level 2 requirement if issued prior to Phase 4 of the plan. Another misread the phase-in plan to mean that self-assessments would no longer be permitted at Full Implementation. One comment asked if the USG would be revisiting acquisition timelines to add more time for due diligence to ensure all entities meet CMMC requirements or have a POA&M in place. Some commenters observed that DoD's intended dates for CMMC implementation, as published in an earlier 48 CFR CMMC interim final rule, are unachievable and must be changed via another CMMC DFARS rule. Some commenters were confused by the differences between the dates of implementation phases in the rule, and the seven years described in cost estimates as necessary to complete implementation. Another commenter asked why the rule only applies to DoD.

Another major problem with shared key authentication is that pre-RSN IEEE 802.11 requires all devices on a WLAN to use the same WEP key or the same small set of keys. This reduces accountability and complicates troubleshooting and incident response efforts. If the WEP key is compromised, it needs to be replaced as quickly as possible to prevent further malicious acts, because WEP keys are used not only for access control, but also to protect confidentiality and integrity (as described in Sections 3.2.2 and 3.2.3). Unfortunately, IEEE 802.11 does not specify any support for key management. When a WEP key needs to be changed, the WLAN administrators have to implement their own methods for generating and distributing a new key. The key needs to be replaced on all STAs and APs, which is a manual process for many WLAN products. WLAN administrators also need to implement methods for archiving, auditing, and destroying keys. Key management problems often limit the scalability of IEEE 802.11 WLANs.

(definition of "Contrary"). Preemption also applies if the provision of State law stands as an obstacle to the accomplishment and execution of the full purposes and objectives and purposes of sec. 264 of HIPAA. Sec. 264 of HIPAA contains the provisions pertaining to the privacy of individually identifiable health information. Back to Citation 1031. Public Law 105-277 , 112 Stat. 2681-528 (Oct. 21, 1998) (codified at 5 U.S.C. 601 note). Back to Citation 1032. Public Law 104-13 , 109 Stat. 163 (May 22, 1995) (codified at 44 U.S.C. 101 note). Back to Citation 1033. "View ICR," supra note 940. Back to Citation 1034. Id. Back to Citation [FR Doc. 2024-30983 Filed 12-27-24; 4:15 pm] BILLING CODE 4153-01-P

(iv) If the export authorization specifies that additional security arrangements are necessary for performance on the contract, the contractor will incorporate those additional arrangements by appropriate provision in the contract or in a separate security document. (v) The contractor will prepare and maintain a written record that identifies the originator or source of classified information that will be used in providing classified defense articles, material or services to foreign customers. The contractor will maintain this listing with the contractor's record copy of the pertinent export authorization. (vi) The contractor will include the security provisions in accordance with paragraph (b)(5) in this section in all contracts and subcontracts involving classified information that are awarded to foreign contractors. Contractors must insert the bracketed contract specific information (e.g., applicable country and disposition of classified material) where noted, when using the following security clauses in the contract. (A) All classified information and material furnished or generated under the contract will be protected to ensure that: (1) The recipient will not release the information or material to any third party without disclosure authorization and export authorization, as appropriate. (2) The recipient will afford the information and material a degree of protection equivalent to that afforded it by the releasing government. (3) The recipient will not use the information and material for other than the purpose for which it was furnished without the prior written consent of the releasing government. (B) Classified information and material furnished or generated under this contract will be transferred through government channels or other channels specified in writing by the governments of the United States and [insert applicable country]. It will only be transferred to persons who have an appropriate security clearance and an official need for access to the information in order to perform on the contract. (C) Classified information and material furnished under the contract will be re-marked by the recipient with its government's equivalent security classification markings. (D) Classified information and material generated under the contract must be assigned a security classification as specified by the Contract Security Classification Specifications, or equivalent, provided with this contract. (E) All cases in which it is known or there is reason to

believe that classified information or material furnished or generated under the contract has been lost or disclosed to unauthorized persons will be reported promptly and fully by the contractor to its government's security authorities. (F) Classified information and material furnished or generated pursuant to the contract will not be further provided to another potential contractor or subcontractor unless: (1

CIS Safeguard 3.8 · Document Data Flows Document data flows. Data flow documentation includes service provider data flows and should be based on the enterprise's data management process. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard. Implementation Groups: 2,3 Asset Type: data Security Function: identify Parent Control: Data Protection

Note that option 1 is used as the baseline in the descriptions of all other options. The variation of the proposed rule with the relaxed lot code requirements is used as the baseline in this table because the high cost of requiring lot codes on all records (\$16.58 billion) is overwhelming. While the reduction in benefits from relaxing the lot code requirements is also large, we thought that the inclusion of that option in this table would confuse the presentation and add little practical value to the policy analysis. 2 Because this chart only reflects food safety, it does not include classified food security scenarios which envision intrastate shipments being targeted for tampering. 3 This option overstates the cost reduction from provisions in the final rule that exclude food contact substance entities since it assumes that they will not have to incur learning, records redesign, and additional records maintenance costs. In the final rule these entities will incur learning costs since they will still be subject to access requirements for records that they keep during the course of normal business activity. We constructed the policy options reported in the following tables to provide a range of net benefit and cost effectiveness measures for alternative coverage options. The records access, retention, and compliance date provisions, as well as the requirements for transporters for all options reported in the following tables, are the same as those reported for option 7 in the previous table. In addition, coverage for the option entitled ·all entities· is the same as that for option 7 in the previous table. Persons handling the finished container that contacts food are excluded from all of the following coverage options for the policy reasons stated previously. However, while persons handling the finished container that contacts food other than those who place food directly in contact with the finished container, are not required to establish and maintain records in the final rule, they are required to provide access to FDA to existing records if the conditions for access are satisfied. This requirement is implicit in all of the options with different coverage reported in the following tables. Table 17. Coverage of Different Policy Options

	Grocery Outlets	Importers and Wholesalers	Manufacturers	Mixed-Type Facilities	Warehouses	Transporters	Option	Adjusted	Comprehensive	All	All	All	All	All	All
(printed page 71644)	A	All	B	All	C	All	All	D	All	All	All	E	All	All	All
F	All	All	All	All	G (final rule)	Exclude very small	All	All	All	All	All	H	Exclude very small	Exclude very small	Exclude very small
I	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small	Exclude very small
	All	All	All	All	All	All	All	Only interstate	Note: Very small firms are defined as those with fewer than 10 full-time equivalent employees.						

The minimum security requirements cover seventeen security-related areas with regard to protecting the confidentiality, integrity, and availability of federal information systems and the information processed, stored, and transmitted by those systems. The security-related areas include: (i) access control; (ii) awareness and training; (iii) audit and accountability; (iv) certification, accreditation, and security assessments; (v) configuration management; (vi) contingency planning; (vii) identification and authentication; (viii) incident response; (ix) maintenance; (x) media protection; (xi) physical and environmental protection; (xii) planning; (xiii) personnel security; (xiv) risk assessment; (xv) systems and services acquisition; (xvi) system and communications protection; and (xvii) system and information integrity. The seventeen areas represent a broad-based, balanced information security program that addresses the management, operational, and technical aspects of protecting federal information and information systems. Certification, Accreditation, and Security Assessments (CA): Organizations must: (i) periodically assess the security controls in organizational information systems to determine if the controls are effective in their application; (ii) develop and implement plans of action designed to correct deficiencies and reduce or eliminate vulnerabilities in organizational information systems; (iii) authorize the operation of organizational information systems and any associated information system connections; and (iv) monitor information system security controls on an ongoing basis to ensure the continued

effectiveness of the controls.

From the NIST SP 800-172 Rev 3 Final Public Draft: system media cannot occur unless two technically qualified individuals conduct the 1295 designated task. Individuals who sanitize system media possess sufficient skills and expertise to determine whether the proposed sanitization reflects applicable federal and organizational standards, policies, and procedures. Dual authorization also helps to ensure that sanitization occurs as intended to protect against errors and false claims of having performed the sanitization actions. To reduce the risk of collusion, organizations consider rotating dual authorization duties to other individuals. Organizations consider the risks associated with implementing dual authorization when immediate responses are necessary to help ensure public and environmental safety. This requirement enhances SP 8

AC.L2-3.1.15 · Privileged Remote Access CMMC Assessment Guide · Level 2 | Version 2.13 48
organizational systems. Note that the ability to affect the integrity of the system is considered security-relevant as that could enable the means to by-pass security functions although not directly impacting the function itself. FURTHER DISCUSSION Privileged users are not necessarily allowed to perform their job functions from a remote location. Likewise, not all privileged commands may be executed remotely. Allowing remote execution of privileged commands or remote access to security-relevant information should be avoided if possible. If absolutely necessary, the p rileged commands authorized for remote execution should be identified and documented. Document which user roles have permissions to remotely execute privileged commands to make changes and to access security relevant information. Documentation must be used to establish security mechanisms that enforce the policy. This requirement, AC.L2 -3.1.15, requires authorization for privileged commands executed during a remote session and complements five other requirements dealing with remote access (AC.L2-3.1.12, AC.L2-3.1.14, AC.L2-3.1.13, IA.L2-3.5.3, and MA.L2-3.7.5): · AC.L2-3.1.12 requires the control of remote access sessions. · AC.L2-3.1.14 limits remote access to specific access control points. · AC.L2-3.1.13 requires the use of cryptographic mechanisms when enabling remote sessions. · IA.L2-3.5.3 requires multifactor authentication for network access to non- privileged accounts. · Finally, MA.L2-3.7.5 requires the addition of multifactor authentication for remote maintenance sessions. This requirement, AC.L2-3.1.15, also extends AC.L2-3.1.2, which limits the types of transactions and functions that authorized users are permitted to execute. Example Your company's Access Control Policy permits certain work roles to remotely perform a limited set of privileged commands from company-owned computers [a] . You implement controls to enforce who can remotely execute a privileged command , which privileged commands they can execute, and who is allowed access to security relevant information such as audit log configuration settings [a,c,d]. Potential Assessment Considerations · Does system documentation identify system administration or security functions that can be executed remotely [a]? · Is execution of the identified privileged commands via remote access only authorized for documented operational needs [c]?

The Department of Defense (DoD) proposes amending the Defense Federal Acquisition Regulation Supplement (DFARS) to add a new contract clause 252.204-70XX, Expediting Contract Closeout, to expedite contract closeout on contracts with a residual dollar amount of \$1,000 or less at the time of final closeout. The objective of the proposed clause is to facilitate expedited contract closeout and avoid excessive administrative costs for both the contractor and the Government to reconcile relatively small residual dollar amounts in order to close out a contract. The proposed rule will apply to small entities that have been or will be awarded contracts, including those under FAR part 12 procedures for the acquisition of commercial items. DoD is unable to estimate the total number of small entities that have DoD contracts with a residual amount of \$1,000 or less; however, the Defense Contract Management Agency (DCMA) was able to provide information on contracts administered by DCMA. According to data available in Mechanization of Contract Administration Services/Shared Data Warehouse as of June 2019, there were 11,831 flexibly-priced contracts with residual dollar amounts of \$1,000 or less, of which 3,507 contracts were awarded to small entities. The average residual amount on these contracts was \$70. The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). The rule does not duplicate, overlap, or conflict with any other Federal rules. There are no known, significant, alternative approaches to the proposed rule that would meet the requirements of the proposed rule. DoD invites comments from small business concerns and other interested parties on the expected impact of this rule on small entities. DoD will also consider comments from small entities concerning the existing regulations

in subparts affected by this rule in accordance with 5 U.S.C. 610 . Interested parties must submit such comments separately and should cite 5 U.S.C. 610 (DFARS Case 2017-D042), in correspondence.

VIII. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). List of Subjects in 48 CFR Parts 204 , 212 , and 252 Government procurement Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204 , 212 , and 252 are proposed to be amended as follows:

1. The authority citation for 48 CFR parts 204 , 212 , and 252 continues to read as follows:
Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 . PART 204-ADMINISTRATIVE AND INFORMATION MATTERS 2. Add section 204.804-70 to read as follows: 204.804-70 Contract clause.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Commerce Office of the Secretary National Institute of Standards and Technology International Trade Administration National Telecommunications and Information Administration [Docket No.: 100721305-0305-01] AGENCY: Office of the Secretary, U.S. Department of Commerce; National Institute of Standards and Technology, U.S. Department of Commerce; International Trade Administration, U.S. Department of Commerce; and National Telecommunications and Information Administration, U.S. Department of Commerce. ACTION: Notice of inquiry. SUMMARY: The Department of Commerce's Internet Policy Task Force is conducting a comprehensive review of the nexus between cybersecurity challenges in the commercial sector and innovation in the Internet economy. The Department seeks comments from all stakeholders, including the commercial, academic and civil society sectors, on measures to improve cybersecurity while sustaining innovation. Preserving innovation, as well as private sector and consumer confidence in the security of the Internet economy, are important for promoting economic prosperity and social well-being overall. In particular, the Department seeks to develop an up-to-date understanding of the current public policy and operational challenges affecting cybersecurity, as those challenges may shape the future direction of the Internet and its commercial use, both domestically and globally. After analyzing comments on this Notice, the Department intends to issue a report that will contribute to the Administration's domestic and international policies and activities in advancing both cybersecurity and the Internet economy. DATES: Comments are due on or before September 13, 2010. ADDRESSES: Written comments may be submitted by mail to Diane Honeycutt, National Institute of Standards and Technology, 100 Bureau Drive, Stop 8930, Gaithersburg, MD 20899. Submissions may be in any of the following formats: HTML, ASCII, Word, rtf, or pdf. Online submissions in electronic form may be sent to cybertaskforce@doc.gov . Paper submissions should include a three and one-half inch computer diskette or compact disc (CD). Diskettes or CDs should be labeled with the name and organizational affiliation of the filer and the name of the word processing program used to create the document. Comments will be posted at <http://www.ntia.doc.gov/-internetpolicytaskforce> and <http://csrc.nist.gov> . FOR FURTHER INFORMATION CONTACT:

Because a notice of proposed rulemaking and an opportunity for public comment are not required to be given for this rule under 41 U.S.C. 1707(a)(1) (see section III. of this preamble), the analytical requirements of the Regulatory Flexibility Act (5 U.S.C. 601 et seq.) are not applicable. Accordingly, no regulatory flexibility analysis is required and none has been prepared.

VII. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). List of Subjects in 48 CFR Parts 204 , 212 , and 252 Government procurement Amy G. Williams, Deputy, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204 , 212 , and 252 are amended as follows: 1. The authority citation for parts 204, 212, and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 . (printed page 24887) PART 204-ADMINISTRATIVE MATTERS 2. Revise section 204.7109 to read as follows: 204.7109 Contract clause. Use the clause at 252.204-7006, Billing Instructions, in solicitations and contracts if Section G includes: (a) Any of the standard payment instructions at PGI 204.7108(d)(1) through (6); or (b) Other payment instructions, in accordance with PGI 204.7108(d)(12), that require contractor identification of the contract line item(s) on the payment request. PART 212-ACQUISITION OF COMMERCIAL ITEMS 212.301 [Amended] 3. Amend section 212.301 by: a. Removing paragraph (f)(ii)(C); and b. Redesignating paragraphs (f)(ii)(D) through (G) as

However, holders of patents are not obligated to respond to ITL calls for patents and ITL has not undertaken a patent search in order to identify which, if any, patents may apply to this publication. As of the date of publication and following call(s) for the identification of patent claims whose use may be required for compliance with the guidance or requirements of this publication, no such patent claims have been identified to ITL. No representation is made or implied by ITL that licenses are not required to avoid patent infringement in the use of this publication. \

_____ ##

CAUTIONARY NOTE The generalized assessment procedures described in this publication provide a framework and starting point for developing specific procedures to assess the enhanced security requirements in NIST Special Publication 800-172. The assessment procedures can be used to help generate and evaluate the relevant evidence needed to determine if the security safeguards employed by organizations are implemented correctly, operating as intended, and satisfy the enhanced security requirements. Organizations have the flexibility to tailor the assessment procedures by selecting the assessment methods and objects needed to achieve the assessment objectives. There is no expectation that every assessment method and object in an assessment procedure will be used for every assessment. In addition, there is significant flexibility in the scope of the assessment and the degree of rigor applied during the assessment process. The assessment procedures can support self-assessments, third-party assessments, or assessments conducted by sponsoring organizations (e.g., government agencies). Such approaches may be specified in contracts or in agreements by participating parties.

in't Mark-up Language (YAML) formats that provide machine-readable representations of security and privacy information relative to the implementation, assessment, and continuous monitoring of systems. NIST SP 800-53, SP 800-53A, and SP 800-53B are available in OSCAL format, and programs such as FedRAMP are leveraging OSCAL.

The bulk of the work defined here will be completed by NSA and NIST personnel, with input from contracted infcHination technology experts. However, review and input fi'om the information technology industry as a whole will be necessary as the Common Criteria development process proceeds. It is understood that the user and vendor community will remain an important source of technical informatiem as this project continues.

The definitions of Organization Seeking Assessment (OSA) and Organization Seeking Certification (OSC) are provided in §.170.4. It is important to note that OSC is a sub-set of OSA. g. Process, Store, or Transmit Comment: Several comments asked about use of the term, 'Process, store or transmit'. One asked about its application to a turnkey cloud based CMMC solution and whether the intent was to consider 'access' a subset of 'process'. Another recommended using the term 'Handle' in lieu of this term and noted that this would also require amendments to DFARS clause 252-204-7012. Another comment recommended rephrasing the definition to provide clarity while another asked that the definition of 'Process, store, or transmit' (§.170.4(b)) explicitly include residence of data in memory, which has not previously been identified in this context and could raise interpretation issues. Response: The phrase 'process, store, or transmit' is more specific than the term 'handle' and is consistent with DoD contract requirements for Non-Federal Information systems as specified in DFARS clause 252.204-7012. The DoD intended 'Access' to be included in the 'Process, store, or transmit definition as written in §.170.4(b). An organization offering a turnkey cloud based CMMC solution would be considered an ESP by this rule, and the rule was updated to address assessment and certification requirements of ESPs. The rule definitions are provided for additional clarity of the terms included in the rule and does not nor cannot include every potential instance of the term's application to a contractor's information systems. h. Clarification of Definitions for FCI and CUI Comment: Three comments requested clarification of and noted inconsistency between the terms 'FCI' and 'CUI'. One perceived '[FCI]' and '[CUI]' as new acronyms and asked why this rule includes them. One comment noted the inconsistent use of the terms 'CUI and FCI' and 'sensitive unclassified information' and recommended selecting one term for use throughout the rule. Another comment requested definitions for CMMC be distinguished with formatting or another notation. Response: FCI is defined in FAR clause 52.204-21. The definition of CUI and general requirements for its

safeguarding are included in 32 CFR 2002.4 and 2002.14, respectively. CUI is not a new acronym. The notation '[FCI]' is identified in table 2 to § 170.15(c)(1)(ii) to reflect its alignment to the requirements of FAR clause 52.204-21 for basic safeguarding of information. Similarly, '[CUI]' has been added to reflect the use of those requirements for CMMC Level 2, which is designed to protect CUI, not FCI. The DoD amended the rule such that 'sensitive unclassified information' will consistently be replaced with 'FCI and/or CUI' as appropriate. i. Use of Terms Information and Data Comment:

(F) From subsection (f) (agency rules for notifying subjects to the existence of records about them, for accessing and amending records, and for assessing fees) because the system is exempt from subsection (d) provisions regarding access and amendment of records by record subjects. Nevertheless, the Office of the Secretary of Defense has published agency rules concerning notification of a subject in response to his request if any system of records named by the subject contains a record pertaining to him and procedures by which the subject may access or amend the records. Notwithstanding exemption, the Office of the Secretary of Defense may determine it appropriate to satisfy a record subject's access request. (20) System identifier and name. DMDC 13 DoD, Defense Clearance and Investigations Index. (i) Exemption. Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is (printed page 14808) denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. Any portion of this system that falls under the provisions of 5 U.S.C. 552a(k)(2) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3); (d); (e)(1); (e)(4)(G), (H), and (I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(2). (iii) Reasons. (A) From subsection (c)(3) because it will enable OSD components to conduct certain investigations and relay law enforcement information without compromise of the information, protection of investigative techniques and efforts employed, and identities of confidential sources who might not otherwise come forward and who furnished information under an express promise that the sources' identity would be held in confidence (or prior to the effective date of the Act, under an implied promise). (B) From subsections (e)(1), (e)(4)(G), (H), and (I) because it will provide protection against notification of investigatory material including certain reciprocal investigations and counterintelligence information, which might alert a subject to the fact that an investigation of that individual is taking place, and the disclosure of which would weaken the on-going investigation, reveal investigatory techniques, and place confidential informants in jeopardy who furnished information under an express promise that the sources' identity would be held in confidence (or prior to the effective date of the Act, under an implied promise).

CM.L2-3.4.4 · Security Impact Analysis CMMC Assessment Guide · Level 2 | Version 2.13 99 FURTHER DISCUSSION Changes to complex environments are reviewed for potential security impact before implemented. Changes to IT systems can cause unforeseen problems and have unintended consequences for both users and the security of the operating environment. Analyze the security impact of changes prior to implementing them. This can uncover and mitigate potential problems before they occur. Example You have been asked to deploy a new web browser plug-in. Your standard change management process requires that you produce a detailed plan for the change, including a review of its potential security impact. A subject-matter expert who did not submit the change reviews the plan and tests the new plug-in for functionality and security. You update the change plan based on the expert's findings and submit it to the change control board for final approval [a]. Potential Assessment Considerations · Are configuration changes tested, validated, and documented before installing them on the operational system [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.4.4

3.3.5, 3. 3.3.5 | | with related policies, PR. 3.3.5 | | with related policies, PR.

From the NIST SP 800-172 Rev 3 Final Public Draft: Larger organizations may implement a dedicated SOC, while smaller organizations NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 may employ third-party organizations to provide this capability. This requirement 1201

(e) If the Government exercises the authority provided in 239.7305(d), the debriefing shall not reveal any information that is determined to be withheld from disclosure in accordance with section

806 of the National Defense Authorization Act for Fiscal Year 2011, as amended by section 806 of the National Defense Authorization Act for Fiscal Year 2013 (see subpart 239.73). PART 233-PROTESTS, DISPUTES, AND APPEALS 7. Add new section 233.102 to read as follows: 233.102 General. If the Government exercises the authority provided in 239.7305(d) to limit disclosure of information, no action undertaken by the Government under such authority shall be subject to review in a bid protest before the Government Accountability Office or in any Federal court (see subpart 239.73). PART 239-ACQUISITION OF INFORMATION TECHNOLOGY 8. Add new subpart 239.73 to read as follows: Subpart 239.73-Requirements for Information Relating to Supply Chain Risk 239.7300 Scope of subpart. 239.7301 Applicability. 239.7302 Definitions. 239.7303 Authorized individuals. 239.7304 Determination and notification. 239.7305 Exclusion and limitation on disclosure. 239.7306 Solicitation provision and contract clause. Subpart 239.73-Requirements for Information Relating to Supply Chain Risk 239.7300 Scope of subpart. (a) This subpart implements section 806 of the National Defense Authorization Act for Fiscal Year 2011 (Pub. L. 111-383) and elements of DoD Instruction 5200.44, Protection of Mission Critical Functions to Achieve Trusted Systems and Networks (TSN), at (<http://www.dtic.mil/whs/directives/corres/pdf/520044p.pdf>). (b) The authority provided in this subpart expires on September 30, 2018 (see section 806(a) of Pub. L. 112-239). 239.7301 Applicability. Notwithstanding FAR 39.001, this subpart shall be applied to acquisition of information technology for national security systems, as that term is defined at 44 U.S.C. 3542(b) , for procurements involving· (a) A source selection for a covered system or a covered item involving either a performance specification (see 10 U.S.C. 2305(a)(1)(C)(ii)), or an evaluation factor (see 10 U.S.C. 2305(a)(2)(A)), relating to supply chain risk; (b) The consideration of proposals for and issuance of a task or delivery order for a covered system or a covered item where the task or delivery order contract concerned includes a requirement relating to supply chain risk (see 10 U.S.C. 2304c(d)(3) and FAR 16.505(b)(1)(iv)(D)); or (c) Any contract action involving a contract for a covered system or a covered item where such contract includes a requirement relating to supply chain risk. 239.7302 Definitions. As used in this subpart· Covered item means an item of information technology that is purchased for inclusion in a covered system, and the loss of integrity of which could result in a supply chain risk for a covered system (see section 806(e)(6) of Pub. L. 111-383). Covered system means a national security system, as that term is defined at 44 U.S.C. 3542(b) (see section 806(e)(5) of Pub. L. 111-38

(4) Propose changes to this rule as deemed appropriate and provide them (printed page 83321) to the applicable CSA for submission to the OUSD(I&S) Counterintelligence, Law Enforcement and Security Directorate. (i) Director, ISOO. The Director, ISOO: (1) Oversees the NSIP and agency compliance with it, in accordance with E.O. 12829 . (2) Issues and maintains the NISP implementing directive (32 CFR part 2004), in accordance with E.O. 12829 , to provide guidance to the CSAs and USG agencies under the NISP. (3) Chairs the NISP Policy Advisory Committee. Addresses complaints and suggestions from contractors, as detailed in the NISP Policy Advisory Committee bylaws. § 117.7 Procedures. (a) General. Contractors will protect all classified information that they are provided access to or that they possess. This responsibility applies at both contractor and USG locations. (b) Contractor Security Officials. Contractors will appoint security officials who are U.S. citizens, except in exceptional circumstances (see § 117.9(m) and § 117.11(e)). (1) Appointed security officials listed in paragraphs (b)(2), (b)(3), and (b)(4) of this section must: (i) Oversee the implementation of the requirements of this rule. Depending upon the size and complexity of the contractor's security operations, a single contractor employee may serve in more than one position. (ii) Undergo the same security training that is required for all other contractor employees pursuant to § 117.12, in addition to their position specific training. (iii) Be designated in writing with their designation documented in accordance with CSA guidance. (iv) Undergo a personnel security investigation and national security eligibility determination for access to classified information at the level of the entity's eligibility determination for access to classified information (e.g., FCL level) and be on the KMP list for the cleared entity. (2) SMO. The SMO will: (i) Ensure the contractor maintains a system of security controls in accordance with the requirements of this rule. (ii) Appoint a contractor employee or employees, in writing, as the FSO and appoint the same employee or a different employee as the ITPSO. The SMO may appoint a single employee for both roles or may appoint one employee as the FSO and a different employee as the ITPSO. (iii) Remain fully informed of the facility's classified operations. (iv) Make decisions based on classified threat reporting and their thorough knowledge, understanding, and appreciation of the threat information and the potential impacts caused by a loss of classified information. (v) Retain accountability for the management and operations of the facility without delegating that accountability to a subordinate manager. (3) FSO. The FSO will: (i) Supervise

and direct security measures necessary for implementing the applicable requirements of this rule and the related USG security requirements to ensure the protection of classified information.

In the final rule, we develop a more comprehensive and detailed model to estimate the food safety benefits using information generated from FDA outbreak investigations (Ref. 2). We use this information to estimate the number of illnesses averted as improved recordkeeping practices lead to faster traceback investigations and higher rates of successful traceback completions. These estimates understate the true expected benefits from the rule, because they are derived solely from food safety data and do not take into account the expected benefits of this rule to food security. The estimate of strictly food security benefits is based on classified data and is not used in this analysis. A qualitative description of the security benefits is provided below under section IV.E.1 of this document, entitled "Bioterrorism Considerations." Although benefit-cost analysis is primarily a quantitative exercise, the existence of non-quantified benefits and costs, as well as uncertainty around the quantified measures, means that assessing whether costs justify benefits entails a qualitative element. Decision aids such as uncertainty analyses are used to help decision makers in these instances. (Comment 179) There were several comments stating that the costs of compliance for specific sectors, including foreign facilities, food contact suppliers, and transportation facilities, did not justify the benefits of reducing the risks of contamination posed by those sectors. (Response) In the final analysis that follows, we refine the analysis of the benefits of selected policy options including those expected from foreign firms, food contact substance suppliers, and transportation facilities. (Comment 180) One comment states the need to measure benefits from the regulation against the existing traceback and recall capability of the industry. This comment questions whether the provisions in the recordkeeping rule would improve response times for removing product from the market, and potentially reduce the number of illnesses from a foodborne outbreak. The comment suggests that FDA should consider what the savings would be in anticipated response times and records recovery times, as well as how this would translate into a reduction in illnesses and enhanced product recovery. Finally, the comment states that the burdensome exercise to produce records could actually slow and hinder the objectives of recalling a suspected product.

173. Wesley Barker, et al., "ONC Data Brief: Hospital Capabilities to Enable Patient Electronic Access to Health Information, 2021," The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, p. 2 and 5 (Oct. 2022) (estimates based on non-Federal acute care hospitals and applications configured to meet the application programming interface (API) specifications in the hospital's EHR), https://www.healthit.gov/sites/default/files/2022-12/hospital_capabilities_to_enable_patient_access_ONC_DB2021-Updated.pdf. Back to Citation 174. Catherine Strawley, et al., "ONC Data Brief: Hospital Use of APIs to Enable Data Sharing Between EHRs and Apps," The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, p. 2 (Sept. 2023) (estimates based on non-Federal acute care hospitals using standards-based APIs to enable patient access), https://www.healthit.gov/sites/default/files/2023-09/DB68-Hospital%20Use%20of%20APIs%20to%20Enable%20Data%20Sharing_508.pdf. Back to Citation 175. See "Determination That A Public Health Emergency Exists Nationwide as the Result of the 2019 Novel Coronavirus," Administration for Strategic Preparedness & Response, U.S. Department of Health and Human Services (Jan. 31, 2020), <https://aspr.hhs.gov/legal/PHE/Pages/2019-nCoV.aspx>; "Renewal of Determination that a Public Health Emergency Exists As a Result of the Continued Consequences of the Coronavirus Disease 2019 (COVID-19) Pandemic," Administration for Strategic Preparedness & Response, U.S. Department of Health and Human Services (Feb. 9, 2023), <https://aspr.hhs.gov/legal/PHE/Pages/COVID19-9Feb2023.aspx>; "Notification of Enforcement Discretion for Telehealth Remote Communications During the COVID-19 Nationwide Public Health Emergency," Office for Civil Rights, U.S. Department of Health and Human Services (Jan. 20, 2021), <https://www.hhs.gov/hipaa/for-professionals/special-topics/emergency-preparedness/notification-enforcement-discretion-telehealth/index.html>. Back to Citation 176. Yuriy Pylypchuk, et al., "ONC Data Brief: Use of Telemedicine among Office-Based Physicians, 2021," The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, p. 1 (Mar. 2023), https://www.healthit.gov/sites/default/files/2023-04/DB65_TelemedicinePhysicians_508.pdf. Back to Citation 177. Nduma N. Basil, "Health Records Database and Inherent Security Concerns: A Review of the Literature," Cureus, p. 3 (Oct. 11, 2022) ("The increase in networked medical equipment and devices implies that, if there is a security breach in the form of hacking, then

traffic on the network can slow down and interfere with the delivery of healthcare services.),
<https://www.ncbi.nlm.nih.gov/pmc/articles/PMC9647912/>. Back to Citation 178. Id. Back to Citation

While the promise of these new technologies is exciting, they come with increased risks and vulnerabilities to ePHI and the information systems that create, receive, maintain, or transmit it. As noted by Executive Order (E.O.) 14110, “[AI] must be safe and secure. Meeting this goal requires [. . .] addressing AI systems’ most pressing security risks—including with respect to biotechnology, cybersecurity, critical infrastructure, and other national security dangers—while navigating AI’s opacity and complexity.” [203] For these reasons, the E.O. required the Secretary of HHS, in consultation with the Secretary of Defense and the Secretary of Veterans Affairs, to establish an HHS AI Task Force to develop a strategic plan that includes policies and frameworks on responsible deployment and use of AI and AI-enabled technologies in the health and human services sector, including the incorporation of safety, privacy, and security standards into the software-development lifecycle for the protection of personally identifiable information, such as measures to address AI-enhanced cybersecurity threats in the health and human services sector. [204] The Department has taken a number of actions to address the use of AI in health care, including establishing an AI Council, appointing a Chief AI Officer, [205] and taking steps to regulate the use of AI in health care. [206] Accordingly, regulated entities must be prepared to identify, mitigate, and remediate such risks and vulnerabilities. While the health care industry has generally shifted from paper record-keeping and non-interoperable electronic devices to an interconnected electronic health care system, it has led to an increasing vulnerability to breaches of unsecured PHI resulting from unauthorized uses and disclosures and cyberattacks. According to an article published by the American Hospital Association Center for Health Innovation, “Health care organizations are particularly vulnerable and targeted by cyberattacks because they possess so much information of high monetary and intelligence value to cyber thieves and nation-state actors.” [207] In fact, “[. . .] on the dark web, PHI is deemed more (printed page 913) valuable than credit card data, enabling cybercriminals to extract as much as [\$1,000] per stolen medical record.” [208] Before this shift to an interconnected electronic system, lost or misplaced paper records or even a laptop could lead to a breach of unsecured PHI affecting hundreds or thousands of individuals. [209] While a breach of that size remains significant, unauthorized access to a single workstation today could lead to a breach that affects millions of individuals because of the increase in interconnectivity. [210] Between 2018 and 2023, the number of breaches of unsecured PHI reported to the Department grew at an alarming rate (100 percent increase), as did the number of individuals affected by such breaches (950 percent increase). [211]

- The Government Performance and Results Act (GPRA) of 1993 establishes the foundation for budget decision making to achieve strategic goals in order to meet agency mission objectives. - The Paperwork Reduction Act (PRA) of 1995 requires agencies to perform their information resource management activities in an efficient, effective, and economical manner. - The Federal Financial Management Improvement Act (FFMIA) of 1996 requires accountability of financial and program managers for financial results of actions taken, control over the federal government’s financial resources, and protection of federal assets. - The Federal Managers Financial Integrity Act (FMFIA) of 1982 requires ongoing evaluations and reports from each executive on the adequacy of administrative control for internal accounting systems. - The Clinger-Cohen Act of 1996 requires agencies to use a disciplined capital planning and investment control (CPIC) process to acquire, use, maintain, and dispose of IT resources, and establishes a role of chief information officer (CIO) within each federal agency. - The E-Government Act of 2002 (Public Law 107-347) promotes better use of the Internet and other IT resources to improve government services for citizens and internal government operations, and provide opportunities for citizen participation in government. The Act also requires agencies to: - -Comply with FISMA, included as Title III of the E-Government Act; - -Support governmentwide e-government initiatives; - -Leverage cross-agency opportunities to further e-government through the Federal Enterprise Architecture (FEA) initiative; and Identifying and implementing security controls is vital in protecting the confidentiality, integrity, and availability of the connected systems and the data that is transferred between the systems.

These principles include making AI safe and secure and protecting privacy and civil liberties. For example, the Department finalized regulations earlier this year that improve transparency by health IT developers of certified health IT, including those that are business associates, that supply a particular type of AI-predictive decision support interventions (DSIs). [916] Specifically,

the regulations require such health IT developers to provide greater transparency about the design, development, training, evaluation, and use of such predictive DSIs. [917] This approach promotes responsible AI and makes it possible for covered entities to access a consistent, baseline set of information about the algorithms they use to support their decision making and to assess such algorithms for fairness, appropriateness, validity, effectiveness, and safety. [918] Additionally, the Department proposes to require that regulated entities monitor authoritative sources for known vulnerabilities and to remediate such vulnerabilities in accordance with their patch management program. We also propose to require that patches, updates, and upgrades that address critical and high risks be applied promptly. Together, these proposals would support the rapid response to vulnerabilities that will be necessary as AI becomes more prevalent. Thus, the Department believes that the adoption of the cybersecurity best practices proposed in this NPRM is an important first step to ensuring that AI tools are deployed by regulated entities in a manner that protects the confidentiality, integrity, and availability of ePHI. 3. Virtual and Augmented Reality (VR and AR) Research on VR and AR technologies is widespread and has produced numerous applications in the health care fields. Such technologies are being used in medical education and patient care, including AR-assisted surgeries, VR-based pain management therapies, and immersive patient education tools. [919] Additionally, innovators are working on ways to incorporate AI with VR and AR for improved diagnostics and treatment planning. [920] However, as with quantum computing and AI, VR and AR technologies raise new privacy and security concerns. VR and AR involve the use of diverse technologies and the collection of a wide array of sensitive information, including comprehensive biometric data. [921] According to experts, “[. . .] VR and AR present distinct security challenges, encompassing typical vulnerabilities associated with electronic devices, as well as potential risks of physical harm and leakage of highly sensitive data.” [922] VR, like any connected computing device, is susceptible to standard cybersecurity concerns and various types of cyberthreats, necessitating proactive anticipation. [923] These cybersecurity risks, such as hacking, social engineering, malicious software, and ransomware, can be mitigated through holistic risk analysis and risk management, consistent with the Security Rule administrative standards in 45 CFR 164.308

b. We determined that the estimate of cleared contractor personnel who would be required to submit foreign travel reports should also include TOP SECRET cleared employees rather than just SECRET cleared employees as indicated in the original rule. As a result, the estimated cost has increased from \$16.81 to \$19.25 million. The following provides details on the estimated increase. All cleared employees, rather than only SECRET cleared employees, must submit foreign travel reports, and receive any pre-travel threat briefings or post travel briefings from the FSO based on the threat according to this rule, SEAD 3, and CSA-provided guidance for unique mission requirements. It is estimated that the number of foreign travel reports submitted annually will increase from 483,681 as estimated in the original rule to 813,054 to comply with the amendment. That estimate is based on analysis of calendar year 2019 unofficial foreign travel reported by DoD civilians and military in the DoD Aircraft and Personnel Automated Clearance System (APACS), a web-based tool for the creation, submission, and approval of aircraft diplomatic clearances and personnel travel clearances (i.e., Country, Theater, and Special Area, as applicable with individual DoD Foreign Clearance Guide (FCG), <https://www.fcg.pentagon.mil> country pages) designed to aid USG travelers on official government and unofficial (e.g., leave) travel. For calendar year 2019, there were 126,131 travelers and 113,214 travel requests submitted into APACS. APACS requirements are published on the DoD FCG, <https://www.fcg.pentagon.mil> . Thus, an annual estimate of .89 expected foreign travel trips by traveler (113,214 divided by 126,131). In the small business analysis, there was a total of 18,242 cleared employees in the 658 small entities sampled and 63,598 cleared employees in the remaining 356 non-small businesses. Of the total cleared employees in the small business analysis (as reported in the National Industrial Security System), approximately 22.3% were at small entities, and 77.7% were at non-small businesses. Known number of new travelers expected to be affected by this proposed rule will increase from the initial estimate of 543,462 to 905,818 cleared contractor personnel, an increase of 362,356 to include TOP (printed page 86292)

but it also must be handled in accordance with the other applicable regulations and laws. Are there specific concerns not addressed in this proposed rule in this area? If so, please provide a relevant use case. VI. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 (as amended by E.O. 14094) and 13563 direct agencies to assess the costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects,

distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is a significant regulatory action and, therefore, was subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. VII. Regulatory Flexibility Act DoD, GSA, and NASA expect this proposed rule, if finalized, to have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601-612. The Initial Regulatory Flexibility Analysis (IRFA) is summarized as follows: DoD, GSA, and NASA are proposing to revise the FAR to implement a NARA final rule on the Federal CUI Program as it relates to performance under Federal contracts (see 32 CFR part 2002). This proposed rule creates two new clauses at FAR 52.204-XX, Controlled Unclassified Information, and FAR 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information, and a new FAR provision at 52.204-WW, Notice of Controlled Unclassified Information Requirements. These clauses and the provision work together to implement a uniform way for Federal agencies, offerors, and contractors to manage CUI. The rule also creates a new standard form (SF) XXX to standardize the way in which the Government identifies CUI that will be managed and safeguarded by a contractor in performance of a contract. This rule is just one element of a larger strategy to improve the Government's efforts to identify, deter, protect against, detect, and respond to increasingly sophisticated attacks by criminals and our adversaries targeting Federal information and information systems. Promulgation of this FAR rule is authorized by 41 U.S.C. 1121(b); 41 U.S.C. 1303; 40 U.S.C. 121(c); 10 U.S.C. chapter 4 and 10 U.S.C. chapter 137 legacy provisions (see 10 U.S.C. 3016); and 51 U.S.C. 20113.

(A) Investigative material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigative material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5), but only to the extent that such material would reveal the identity of a confidential source. (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and/or (k)(5) from the following subsections of 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (H) and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5). (iii) Reasons. (A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation or prosecutable interest by the NRO or other agencies. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence. (B) From subsections (d)(1) through (d)(4), and (f) because providing access to investigative records and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear.

NIST recommends that Federal agencies implement the following recommendations to assist in establishing and maintaining robust security for their IEEE 802.11i-based WLANs. Personnel responsible for their implementation and maintenance should read the corresponding sections of the document to ensure they have an adequate understanding of important related issues.

(b) The appellant will be notified of the decision on his or her appeal in writing. If the decision affirms the adverse determination in whole or in part, the notification will include a brief

statement of the reason(s) for the affirmation, including any exemptions applied, and will inform the appellant of the Privacy Act provisions for judicial review of the appellate authority's decision. If the adverse determination is reversed or modified, in whole or in part, the appellant will be notified in writing of this decision and the request will be reprocessed in accordance with that appeal decision. (c) In order to seek a judicial review of a denial of a request for access to records, a requester must first file an appeal under this section. (d) An appeal ordinarily will not be acted on if the request becomes a matter of litigation. § 310.7 Requests for amendment or correction of records. (a) If the record is not subject to amendment and correction as stated in paragraph (b) of this section, an individual may make a request for amendment or correction of a DoD Component's record about that individual by writing directly to the DoD Component that maintains the record as identified in the published SORN applicable to the record. The request should identify each particular record in question, state the amendment or correction that is sought, and state why the record is not accurate, relevant, timely, or complete without the correction. The individual will also need to verify identity in the same manner as described in §§ 310.3(c) through (d). Factual documentation that is helpful to the DoD Component privacy officials should be submitted with the request. If it is believed that the same record exists in more than one system of records, this should be stated in the request, and the request should be addressed to each DoD Component that maintains a system of records containing the record as noted in this paragraph. (b) Certain records are not subject to amendment or correction under the Privacy Act: (1) Proceedings and determinations of courts-martial, military tribunal, or Military Boards of Correction are not generally subject to amendment or correction under the Privacy Act. (2) Records in systems of records that have been exempted from amendment and correction under the Privacy Act, 5 U.S.C. 552a(j) or (k) are not subject to amendment or correction. (3) The amendment process is not intended to permit the alteration of records presented in the course of judicial or quasi-judicial proceedings such as the adjudication process for personnel security clearances or contesting grades in academic records. Any amendments or changes to these records normally are made through the specific procedures established for the amendment of such records.

Clarification was requested regarding C3PAOs' timelines for accreditation and their dependencies on the CMMC AB accreditation process. Some commenters requested additional time. Clarification was also requested on the current disposition of authorized C3PAOs. A few comments asked for simplification and clarification of the difference between the terms 'authorized' and 'accredited' with the establishment of C3PAOs. One comment requested that the rule be edited to require full compliance before C3PAOs can conduct certifications, and that duplicative language relating to ethics, record keeping, etc., be moved to a central location in the rule. One commentor questioned whether § 170.9(b)(16), which states 'Ensure that all CMMC assessment activities are performed on the information system within the CMMC Assessment Scope', applies to all C3PAO personnel or just those involved in the Quality Assurance process. Other comments objected to the requirement that C3PAOs obtain a CMMC Level 2 certification assessment because the assessment does not result in a Level 2 certification. They asked whether this would require two separate assessments every three years for C3PAOs that also conduct contractor work for DoD. Two comments requested clarification on determining the scope for a CMMC Level 2 assessment of a C3PAO to be used by DIBCAC, and if or when they would be required to obtain a FedRAMP Moderate certification. Also, clarification was requested on whether a C3PAO is permitted to (printed page 83121) possess OSC CUI and other artifacts during the assessment so long as they are destroyed upon completion of the assessment. One comment suggested that all information collected by the C3PAO be encrypted. Three comments asked for clarification on what constitutes a C3PAO assessment team and whether it can consist of solely a Lead CCA. One commentor asked whether entities accredited under ISO 17020:2012(E) by another accreditation body, rather than the CMMC AB, meets CMMC C3PAO requirements. A couple of comments asked for clarification on whether a C3PAO could be foreign owned and participate in the current CMMC AB Marketplace. Response: One commenter misinterpreted several sections of the CMMC rule. By defining the requirements in this rule to become a C3PAO, and defining a scoring methodology, the DoD is providing the authority and guidance necessary for C3PAOs to conduct assessments.

When the contract includes an SF XXX that identifies CUI to be safeguarded under the contract, the contract will include the CUI clause. The contractor or subcontractor will need to review the SF XXX to determine what information under the contract is considered CUI and subject to the compliance requirements of the CUI clause. If the contractor or subcontractor intends to flow down CUI in performance of the contract or subcontract, then the contractor or subcontractor will need to prepare an SF XXX, as appropriate for CUI that will flow down, and distribute it to the

subcontractor that will be handling CUI. Train Contractor Employees on Handling CUI. Per the CUI clause, a contractor shall not permit any contractor employee to have, retain access to, create, collect, use, process, store, maintain, disseminate, disclose, dispose of, or otherwise handle, CUI unless the employee has completed training on properly handling CUI that, at a minimum, includes the elements required in the SF XXX. The SF XXX will also specify the frequency at which a contractor must provide the training, which is dependent on the type of CUI being handled by the contractor's employees and the criticality of the program being supported. The contractor must provide evidence of employee training upon request by the contracting officer; however, such requests are expected to be limited to, for example, instances where the Government is dealing with a CUI incident, or where an agency determines that it is necessary to verify training based on the criticality of a program and the CUI being handled by the contractor. Comply with NIST SP 800-172. A limited number of contractors may be required under FAR clause 52.204-XX, Controlled Unclassified Information, to (printed page 4288) implement some or all requirements of NIST SP 800-172, Enhanced Security Requirements for Protecting Controlled Unclassified Information: A Supplement to NIST Special Publication 800-171, Revision 2. NIST SP 800-172 provides enhanced security requirements that apply only to components of nonfederal systems that process, store, or transmit CUI or that provide security protection for such components when the designated CUI is associated with a critical program or high-value asset. The enhanced requirements supplement the basic and derived security requirements in NIST Special Publication 800-171, Revision 2, and address the protection of CUI by promoting: penetration-resistant architecture, damage-limiting operations, and designs to achieve cyber resiliency and survivability. Submit Supporting Documentation to Verify Compliance.

From the NIST SP 800-172 Rev 3 Final Public Draft: defense-in-depth Information security strategy integrating people, technology, and operations capabilities to establish variable barriers across multiple layers and missions of the organization. NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 discussion 2895

is defined in § 170.17(a)(1)(ii). (CMMC-custom term) CMMC Level 2 Conditional Self-Assessment is defined in § 170.16(a)(1)(ii). (CMMC-custom term) CMMC Level 2 Final Certification Assessment is defined in § 170.17(a)(1)(iii). (CMMC-custom term) CMMC Level 2 Final Self-Assessment is defined in § 170.16(a)(1)(iii). (CMMC-custom term) CMMC Level 3 Conditional Certification Assessment is defined in § 170.18(a)(1)(ii). (CMMC-custom term) CMMC Level 3 Final Certification Assessment is defined in § 170.18(a)(1)(iii). (CMMC-custom term) CMMC Third-Party Assessment Organization (C3PAO) means an organization that has been accredited by the Accreditation Body to conduct CMMC Level 2 Certification Assessments and has the roles and responsibilities identified in § 170.9. (CMMC-custom term) Contractor is defined in 48 CFR 3.502-1. Contractor Risk Managed Assets are defined in table 3 to § 170.19(c)(1) CMMC Level 2 Scoping. (CMMC-custom term) Controlled Unclassified Information (CUI) is defined in 32 CFR 2002.4(h). Controlled Unclassified Information (CUI) Assets means assets that can process, store, or transmit CUI. (CMMC-custom term) DCMA DIBCAC High Assessment means an assessment that is conducted by Government personnel using NIST SP 800-171A, Assessing Security Requirements for Controlled Unclassified Information that: (i) Consists of: (A) A review of a contractor's Basic Assessment; (B) A thorough document review; (C) Verification, examination, and demonstration of a contractor's system security plan to validate that NIST SP 800-171 security requirements have been implemented as described in the contractor's system security plan; and (D) Discussions with the contractor to obtain additional information or clarification, as needed; and (ii) Results in a confidence level of 'High' in the resulting score. (Source: DFARS Clause 252.204-7020, see 48 CFR 252.204-7020). Defense Industrial Base (DIB) is defined in 32 CFR 236.2. Enterprise means an organization with a defined mission/goal and a defined boundary, using information systems to execute that mission, and with responsibility for managing its own risks and performance. An enterprise may consist of all or some of the following business aspects: acquisition, program management, financial management (e.g., budgets), human resources, security, and information systems, information and mission management. (Source: CNSSI 4009; <https://www.cnss.gov/CNSS/issuances/Instructions.cfm>).] External Service Provider (ESP) means external people, technology, or facilities that an organization utilizes for provision and management of comprehensive IT and/or cybersecurity services on behalf of the organization. In the CMMC Program, CUI or Security Protection Data (e.g., log data, configuration data), must be processed, stored, or transmitted on the ESP assets to be considered an ESP. (CMMC-custom term) Federal Contract Information (FCI) is defined in 48 CFR 4.1901. Federal Contract Information (FCI) Assets

The Accreditation Body is responsible for authorizing and ensuring the accreditation of CMMC Third-Party Assessment Organizations (C3PAOs) in accordance with ISO/IEC 17020:2012 (incorporated by reference, see § 170.2) and all applicable authorization and accreditation requirements set forth. At any given point in time, there will be only one Accreditation Body for the DoD CMMC Program. (b) Requirements. The Accreditation Body shall: (1) Become and remain a member in good standing of the Inter-American Accreditation Cooperation (IAAC) and become an International Laboratory Accreditation Cooperation (ILAC) Mutual Recognition Arrangement (MRA) signatory, with a signatory status scope of ISO/IEC 17020:2012. (2) Become and remain a member in good standing of the International Accreditation Forum (IAF) with mutual recognition arrangement signatory status scope of ISO/IEC 17024:2012 (incorporated by reference, see § 170.2). (3) Achieve and maintain full compliance with ISO/IEC 17011:2017 (incorporated by reference, see § 170.2) and complete a peer assessment by other ILAC signatories for competence in accrediting conformity assessment bodies to ISO/IEC 17020:2012, both within 24 months of DoD approval. If ISO/IEC 17011:2017 is revised or superseded, the Accreditation Body shall achieve full compliance with the updated standard within 12 months of the date of revision. (i) Prior to achieving full compliance as set forth in this paragraph (b)(3), the Accreditation Body shall: (A) Authorize, but not accredit, C3PAOs who meet all requirements set forth in § 170.9 to grant CMMC Level 2 Certification Assessments and issue certificates of assessment for OSCs. (B) Require all C3PAOs to achieve and maintain the ISO/IEC 17020:2012 requirements within 27 months of authorization. If ISO/IEC 17020:2012 is revised or superseded, the Accreditation Body shall require full compliance with the updated standard within 12 months of the date of revision. (ii) After achieving full compliance as set forth in this paragraph (b)(3), the Accreditation Body shall accredit C3PAOs, in accordance with ISO/IEC 17020:2012, or subsequent revisions, who meet all requirements set forth in § 170.9 to grant CMMC Level 2 Certification Assessments and issue certificates of assessment for OSCs.

Under CMMC Level 2 (NIST SP 800-171 Rev 3), organizations must implement specific controls addressing this area. Key considerations include: 1. The specific NIST SP 800-171 controls that apply to this scenario 2. Documentation requirements for the SSP 3. Evidence needed for C3PAO assessment 4. Cost-effective implementation options for different organization sizes Organizations should reference the specific control families in NIST SP 800-171 Rev 3 and consult the CMMC Assessment Guide Level 2 for detailed assessment objectives. A Registered Practitioner (RP) can provide organization-specific guidance.

The specific federal statute or Executive Order that authorizes collection of the requested information. (b) Principal Purpose(s): The principal purpose or purposes for which the information is to be used. (c) Routine Uses(s): Disclosure of the information outside DOD. (d) Disclosure: Whether providing the information is voluntary or mandatory and the effects on the individual if he or she chooses not to provide the requested information. (1) Example of a Privacy Act Statement (i) Authority: Emergency Supplement Act of 2000; Public Law 106-246 ; 5 U.S.C. 3013 , Secretary of the Army; 10 U.S.C. 5013 , Secretary of the Navy; 10 U.S.C. 8013 , Secretary of the Air Force; Department of Defense Directive 8500.aa, Information Assurance (IA); and E.O. 9397 (SSN). (ii) Principal Purpose(s): To control access to DOD information, information based systems and facilities by authenticating the identity of a person using a measurable physical characteristic(s). This computer system uses software programs to create biometrics templates and summary statistics, which are used for purposes such as assessing system performance or identifying problem areas. (iii) Routine Use(s): None. The DoD Blanket Routine Uses set forth at the beginning of the Army's Compilations of System of Records Notices applies to this system. (iv) Disclosure: Voluntary; however, failure to provide the requested information may result in denial of access to DOD information based systems and/or DOD facilities. (2) [Reserved]. Appendix D to Part 505-Exemptions; Exceptions; and DoD Blanket Routine Uses (a) Special Exemption. 5 U.S.C. 552a(d)(5) Denies individual access to any information compiled in reasonable anticipation of civil action or proceeding. (b) General and Specific Exemptions. The Secretary of the Army may exempt Army systems of records from certain requirements (printed page 46068) of the Privacy Act. The two kinds of exemptions that require Secretary of the Army enactment are General and Specific exemptions. The Army system of records notices for a particular type of record will state whether the Secretary of the Army has authorized a particular General and Specific exemption to a certain type of record. The Army system of records notices are published in DA Pam 25-51 and on the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy/> . (c) Twelve Exceptions to the No Disclosure without Consent rule of the Privacy Act. (1) 5 U.S.C. 552a(b)(1) To DOD officers and employees who have a need for the record in the performance of their official duties.

This is the official need to know concept. (2) 5 U.S.C. 552a(b)(2) FOIA requires release of the information. (3) 5 U.S.C. 552a(b)(3) The Routine Use Exception. The Routine Use must be published in the Federal Register and the purpose of the disclosure must be compatible with the purpose for the published Routine Use. The applicable Routine Uses for a particular record will be listed in the applicable Army Systems Notice. (4) 5 U.S.C. 552a(b)(4)

Recommendations to add or modify requirements specified in NIST documentation should be submitted in response to NIST requests for public comment on the applicable guidelines. Federal and DoD requirements for delivery of software bills of material of secure software development are beyond the scope of this rule, which is limited to the assessment of compliance with requirements for adequate protection of FCI and CUI. Federal Contract Information is defined in FAR clause 52.204-21, which also provides the security requirements applicable for basic safeguarding of such information. The Department has no authority to modify definitions established in the FAR for application to all executive branch agencies. Any data that meets the definition of FCI, is subject to CMMC Level 1. It is beyond the scope of the CMMC rule to render decisions on specific elements of data. The OUSD(A&S) was not replaced by the DoD CIO, rather, CMMC Program management oversight has been realigned from the OUSD(A&S) to the Office of the DoD CIO for better integration with the Department's other DIB cybersecurity related initiatives. Comments pertaining to DoD's organizational structure are not relevant to the content of this rule. DoD's processing of FOIA requests is also not within the scope of this rule. The DoD declines to respond to speculative or editorial comments about private citizens or outside entities, all of which are beyond the scope of this rule. Likewise, the DoD will not comment here on other DoD cybersecurity related programs, such as Zero Trust. Some comments expressed appreciation for cybersecurity related services that DoD provides free of charge, including protected DNS, vulnerability scanning, and security alerts, but these programs are outside the CMMC program. The government cannot comment on specific implementation or documentation choices of an OSA. Comments on alternate risk mitigation strategies such as product monitoring or software testing are not within the scope of this rule text. d. DoD Policies Supporting CMMC Implementation Comment:

(Response) The proposed rule required large and small firms to provide access to records up to 4 hours after a request made during business hours, and up to 8 hours after a request made after business hours. FDA's current experience is that access to records generally takes 2 to 3 days and the requirements in the regulation will considerably increase the speed of traceback investigations. To acknowledge the concerns addressed by these comments, FDA has relaxed the records access requirement to as soon as possible, but within 24 hours. This longer requirement should provide regulatory relief to small businesses; however, FDA reiterates that it expects all businesses to provide access as soon as possible, given that an access request would only be made in a food-related emergency. (Comment 220) Several comments request an exemption for some specific categories of small business, because they believe the estimated costs of compliance for small businesses are inadequate. Furthermore, one comment states that the regulatory flexibility provisions in the proposed rule did not satisfy SBREFA obligations. (Response) FDA addresses SBREFA's regulatory flexibility issues by (printed page 71648) exempting very small retailers, and by staggering compliance dates so that small and very small businesses would have 18 and 24 months to comply with the regulation. Because food in commerce generally passes through at least one small business before reaching consumers, excluding small businesses in every sector from compliance with the regulation would risk severely compromising the effectiveness of the regulation due to breaks in the recordkeeping chain during traceback investigations. (Comment 221) Some comments argue that FDA should address the relatively large burden on small businesses due to the cumulative cost of the four bioterrorism regulations when considered together. The comments state that the proposed registration rule estimated that approximately 16 percent of foreign businesses might cease to export to the United States as a result of that rule. The comments note that this figure was used in the sensitivity analysis in the proposed recordkeeping rule to estimate the costs of the rule with 16 percent fewer foreign facilities. However, the comments stated that FDA did not consider the costs of all the bioterrorism regulations combined on small (or other) businesses. (Response) The cumulative costs of multiple regulations are rarely considered in regulatory impact analyses. However, costs of the other three regulations were analyzed in their respective regulatory impact analyses. To estimate the cumulative costs of the regulation one could add together the costs determined for all four regulations. VI. Unfunded Mandates Title II of the Unfunded Mandates Reform Act of 1995 (Public Law 104-4

- Applying a threat-centric approach to security requirements specification; - Employing system and security architectures that support logical and physical isolation using system and network segmentation techniques, virtual machines, and containers; 16 - Implementing dual authorization controls for the most critical or sensitive operations; - Limiting persistent storage to isolated enclaves or domains; - Implementing a comply-to-connect approach for systems and networks; - Extending configuration management requirements by establishing authoritative sources for addressing changes to systems and system components; - Periodically refreshing or upgrading organizational systems and system components to a known state or developing new systems or components; - Employing a security operations center with advanced analytics to support continuous monitoring and protection of organizational systems; and - Using deception to confuse and mislead adversaries regarding the information they use for decision-making, the value and authenticity of the information they attempt to exfiltrate, or the environment in which they are operating. | FAMILY | FAMILY |

|-----|-----| | Access Control |

Media Protection | | Awareness and Training | Personnel Security | | Audit and Accountability |

Physical Protection | | Configuration Management | Risk Assessment | | Identification and Authentication | Security Assessment | | Incident Response | System and Communications Protection |

| Maintenance | System and Information Integrity | ## 3.1 ACCESS CONTROL

DFARS 252.204-7012 (Safeguarding Covered Defense Information and Cyber Incident Reporting) Core CUI protection clause requiring NIST SP 800-171 implementation, cyber incident reporting within 72 hours, and preservation of evidence. Contractors should review the full text of DFARS 252.204-7012 in conjunction with their contracting officer and legal counsel to ensure full compliance. The clause should be read alongside the CMMC requirements at 32 CFR Part 170.

Email: pivtesting@nist.gov NIST Special Publication (SP) 800-157 contains technical guidelines for the implementation of standards-based, secure, reliable, interoperable Public Key Infrastructure (PKI)-based identity credentials that are issued for mobile devices by federal departments and agencies to individuals who possess and prove control over a valid Personal Identity Verification (PIV) Card. This document, SP 800-166, contains the requirements and test assertions for testing the Derived PIV Application and associated Derived PIV data objects implemented on removable hardware tokens and within mobile devices. The tests reflect the design goals of interoperability and interface functions. The authors (David Cooper, Hildegard Ferraiolo and Ramaswamy Chandramouli of NIST; Nabil Ghadiali of the National Gallery of Art; and Jason Mohler and Steven Brady of Electrosoft Services, Inc.), wish to thank their colleagues who reviewed drafts of this document and contributed to its development. Special gratitude to the General Services Administration (GSA) FIPS 201 Evaluation Program (GSA FIPS 201 EP) team for their review and contributions to the document.

(b) It does not apply to the National Guards of the States, Territories, and District of Columbia, except to the extent that they are in the possession of NGB records or relying on a System of Records Notice (SORN) published by NGB for their authority to maintain 5 U.S.C. 552a protected records. §-329.3 Definitions. All terms used in this part which are defined in 5 U.S.C. 552a shall have the same meaning herein. Access. Allowing individuals to review or receive copies of their records. Accuracy. Within sufficient tolerance for error to assure the quality of the record in terms of its use in making a determination. Agency. Any Executive department, military department, Government corporation, Government controlled corporation, or other establishment in the executive branch of the [federal] Government (including the Executive Office of the President), or any independent regulatory agency (as defined by 5 U.S.C. 552a). Amendment. The process of adding, deleting, or changing information in a System of Records (SOR) to make the data accurate, relevant, timely, and/or complete. Appellate Authority. The individual with authority to deny requests for access or amendment of records under 5 U.S.C. 552a . Breach. A loss of control, compromise, unauthorized disclosure, unauthorized acquisition, unauthorized access, or any similar term referring to situations where a person other than authorized users (with an official need to know), and for an other than authorized purpose has access or potential access to personally identifiable information, whether physical or electronic. A breach can include identifiable information in any form. (As defined by DoD Director of Administration and Management Memo, 5 Jun 2009 entitled ·Safeguarding Against and Responding to the Breach of Personally Identifiable Information (PII)· (Available at http://www.dod.mil/-pubs/-foi/-privacy/-docs/-DA_-M6_-5_-2009Responding_.toBreach_.of_.PII_.).) Chief, National Guard Bureau (CNGB). A principal advisor to the Secretary of Defense, through the Chairman of the Joint Chiefs of Staff, on matters involving non-federalized National Guard forces

and on other matters as determined by the Secretary of Defense; and the principal adviser to the Secretary of the Army and the Chief of Staff of the Army, and to the Secretary of the Air Force and the Chief of Staff of the Air Force, on matters relating to the National Guard, the Army National Guard of the United States, and the Air National Guard of the United States. The CNGB also represents the National Guard on the Joint Chiefs of Staff. Completeness. All elements necessary for making a determination are present before such determination is made. Computer Matching Program. A program that matches the personal records in computerized database of two or more Federal agencies. Denial Authority. The individual with authority to deny requests for access or amendment of records under 5 U.S.C. 552a . Determination.

s related to cybersecurity. The focus is on the science, technology, engineering, and math disciplines in order to help provide a pipeline of skilled workers for private sector and government; 3. Track 3: Federal Cybersecurity Workforce Structure which is led by Office of Personnel Management (OPM). The goal of this track is to define cybersecurity jobs in the federal government and skills and competencies required. They will also identify new strategies to ensure federal agencies attract, recruit, and retain skilled employees to accomplish cybersecurity missions; and 4. Track 4: Cybersecurity Workforce Training and Professional Development. This track is led by Department of Defense, Office of the Director of National Intelligence, and DHS. The goal of this track is to identify and manage the cybersecurity training and professional development required for federal government civilian, military, and contractor personnel.

Let df be the derivation function specified in Section 10.3.2. When instantiation is performed using this method, a nonce is required, whereas using the method in Section 10.2.1.3.1 does not require a nonce, since full entropy is provided when using that method. Let df be the derivation function specified in Section 10.3.2. Let df be the derivation function specified in Section 10.3.2.

Control EG-21: Machine PP Protection Profile PRIME Privacy and Identity Management for Europe PRP Policy Retrieval Point RBAC Role-Based Access Control RDF Resource Description Framework REL Rights Expression Language RuBAC Rule-Based Access Control RuleML Rule Markup Language SA Access Control System Administrator SAML Security Assertion Markup Language SAO Subject, Action, Object SCA Service Component Architecture SCAP Security Content Automation Protocol SI Access Control System Implementer SNMP Simple Network Management Protocol SoD Separation of Duty SP Special Publication SSO Single Sign-On SSoD Static Separation of Duty SU Access Control System User SWRL Semantic Web Rule Language Turtle Terse RDF Triple Language UMBC University of Maryland, Baltimore County W3C World Wide Web Consortium WAF Web Application Formats WIQA-PL Web Information Quality Assessment Policy Language WYSIWYG What You See Is What You Get XACML Extensible Access Control Markup Language XML Extensible Markup Language XrML Extensible Rights Management Language ## Appendix C-References [ACPT] Access Control Policy Tool - ACPT,

Additional Guidance on Level 2 Scoping CMMC Assessment Scope · Level 2 | Version 2.13 5 Additional Guidance on Level 2 Scoping The OSA is required to document all asset categories that are part of the Level 2 self-assessment or certification assessment in an asset inventory and provide a network diagram of the CMMC Assessment Scope to facilitate scoping discussions during pre-assessment activities. CUI Assets CUI Assets process, store, or transmit CUI as follows: · Process · CUI can be used by an asset (e.g., accessed, entered, edited, generated, manipulated, or printed). · Store · CUI is inactive or at rest on an asset (e.g., located on electronic media, in system component memory, or in physical format such as paper documents). · Transmit · CUI is being transferred from one asset to another asset (e.g., data in transit using physical or digital transport methods). CUI Assets are part of the CMMC Assessment Scope and are assessed against all CMMC requirements. In addition, the OSA is required to: · document each asset in an asset inventory; there is no requirement to embed each asset in the System Security Plan (SSP); · document the treatment of these assets in the SSP; · provide a network diagram of the CMMC Assessment Scope (to include these assets) to facilitate scoping discussions during the pre-assessment. Security Protection Assets/Security Protection Data Security Protection Assets provide security functions or capabilities within the OSA's CMMC Assessment Scope. Security Protection Assets are part of the CMMC Assessment Scope and are assessed against Level 2 security requirements that are relevant to the capabilities provided. For example, an External Service Provider (ESP), defined in 32 CFR §170.4, that provides a security information and event management (SIEM) service may be separated logically and may not process CUI, but the SIEM does contribute to meeting the CMMC requirements within the OSA's CMMC Assessment Scope. Table 2 provides examples of Security

Protection Assets. Security Protection Data means data stored or processed by Security Protection Assets that are used to protect an OSA's assessed environment. Security Protection Data is security-relevant information which, if disclosed, could aid an attacker in the compromise of the system. It includes, but is not limited to:

- configuration data required to operate a security protection asset,

All submissions received must include the agency name and docket number or RIN for this Federal Register document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing at <http://www.regulations.gov> as they are received without change, including any personal identifiers or contact information. FOR FURTHER INFORMATION CONTACT: Valerie Heil, 703-692-3754. SUPPLEMENTARY INFORMATION: I. Overview of the NISP and NISPOM In April 1990, President George Bush directed the National Security Council to explore the creation of a single, integrated industrial security program to improve security protection and provide cost savings. Prior to this, contractors doing business with different U.S. Government (USG) agencies which required access to classified information had to meet different requirements to protect the same levels of classified information, e.g., the type of safe to protect a specific classified item could vary across both contracts and agencies. The diversity of industrial security requirements levied on contractors by an estimated 21 USG agencies created a significant burden on both industry and government and increased the cost of the goods and services provided to the USG. Representatives from government and industry participated in an initiative which led to the creation of Executive Order (E.O.) 12829 National Industrial Security Program (NISP) (available at <https://www.archives.gov/files/isoo/policy-documents/eo-12829-with-eo-13691-amendments.pdf>). With the National Security Council providing overall policy direction, this E.O. established the NISP as the single integrated program to protect classified information and preserve our Nation's economic and technological interests. Nothing in the E.O. shall supersede the authority of the Secretary of Energy or the Nuclear Regulatory Commission under the Atomic Energy Act of 1954, as amended, or the authority of the Director of National Intelligence (or any Intelligence Community element) under the Intelligence Reform and Terrorism Prevention Act of 2004, the National Security Act of 1947, as amended, or Executive Order No. 12333 of December 8, 1981, as amended, or the authority of the Secretary of Homeland Security, as the Executive Agent for the Classified National Security Information Program established under Executive Order 13549 of August 18, 2010 (Classified National Security Information Program for State, Local, Tribal, and Private Sector Entities). The Information Security Oversight Office (ISOO), a component of the National Archives and Records Administration (NARA), was tasked with overseeing overall implementation of the NISP with the goal of: Holding classification activity to the minimum necessary to protect the national security; ensuring the safeguarding of classified national security information in both USG and industry in a cost-effective and efficient manner; and

- (1) STEP 1: DEFINE YOUR SYSTEM . The purpose of Step 1 is to produce a general definition of your system by looking at several key system features: composition, connections, size, cost(s), and back-ups. First, the current configuration of your system is established to ensure that you have fully identified all major system components and connections. Use of a system configuration diagram provides you a visual opportunity to record and review your system's current configuration. It also allows you to visualize potential vulnerabilities that may exist as a result of your system's connections and data flows. Second, Step 1 helps you in developing a general cost estimate for your system so that you are able to appreciate how much it would cost to replace it in its entirety. It is also important to have a general appreciation for the cost of your system in order to decide which countermeasures, if any, are justified based on the cost of your system. Step 1 also reviews the type of software and data used by your system, with the objective of understanding approximately how much labor went into the development of each and whether back-ups are available and necessary. GENERAL PURPOSE OF STEP 1 : The purpose of Step 1 is to develop a general definition of your system. The definition is developed by looking at several key system features: composition, connections, size, cost(s), and back-ups. First, the current configuration of your system is established to ensure that you have fully identified all system components and connections. Use of a diagram provides a visual record of your current system configuration. It also allows you to visualize potential vulnerabilities that may exist as a result of your system's connections and data flows. Second, Step 1 helps you in developing a general cost estimate for your system so that you are able to appreciate how much it would cost to replace it in its entirety.

There are no nonrecurring or recurring engineering costs associated with CMMC Level 2 C3PAO

Certification since it is assumed the contractor has implemented NIST SP 800-171 R2 requirements.

Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 2 C3PAO Certification and affirmation for a small entity is *\$101,752. The three-year cost is \$104,670 (as summarized in section 3(b) above, table 1), and includes the triennial assessment + affirmation plus two additional annual affirmations (\$101,752 + \$1,459 + \$1,459).

- Phase 1: Planning and preparing for the assessment: \$20,699 A director (MGMT5) for 54 hours (\$190.52/hr × 54hrs = \$10,288) An external service provider (ESP) for 40 hours (\$260.28/hr × 40hrs = \$10,411)
- Phase 2: Conducting the C3PAO assessment: \$45,509 A director (MGMT5) for 64 hours (\$190.52/hr × 64hrs = \$12,193) An external service provider (ESP) for 128 hours (\$260.28/hr × 128hrs = \$33,316)
- Phase 3: Reporting of C3PAO Assessment Results: \$2,851 A director (MGMT5) for 4 hours (\$190.52/hr × 4hrs = \$762) An external service provider (ESP) for 8 hours (\$260.28/hr × 8hrs = \$2,082) A staff IT specialist (IT4) for 0.08 hours (\$86.24/hr × 0.08hrs = \$7)
- Affirmation -initial affirmation post assessment: \$1,459
- C3PAO Costs: C3PAO engagement inclusive of Phases 1, 2, and 3 (3-person team) for 120 hours (\$260.28/hr × 120hrs = \$31,234)
- Reaffirmations: It is estimated that the costs to reaffirm a CMMC Level 2 C3PAO Assessment annually is \$1,459 (three-year cost is \$4,377, or \$1,459 × 3)
- A director (MGMT5) for 4 hours (\$190.52/hr × 4hrs = \$762)
- A staff IT specialist (IT4) for 8.08 hours (\$86.24/hr × 8.08hrs = \$697)

Summary: The following is the annual small entities total cost summary for CMMC Level 2 Certifications and Affirmations over a ten-year period: (Example calculation, Year 2: (*\$101,752 assessment per entity × 1,926 entities) + (\$1,459 annual affirmation per entity × 382 entities) = \$196,531,451) (printed page 83208) CMMC Level 3 Certification and Affirmation Costs for Small Business Entities

Purpose The purpose of the Select step is to select, tailor, and document the controls necessary to protect the information system and organization commensurate with risk to organizational operations and assets, individuals, other organizations, and the Nation. NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

CHAPTER THREE PAGE 51 This publication is available free of charge from:

<https://doi.org/10.6028/NIST.SP.800-37r2> Expected Outputs: Controls selected for the system and the environment of operation. Primary Responsibility: System Owner; Common Control Provider. Supporting Roles: Authorizing Official or Authorizing Official Designated Representative; Information Owner or Steward; Systems Security Engineer; Privacy Engineer; System Security Officer; System Privacy Officer. System Development Life Cycle Phase: New · Development/Acquisition. Existing · Operations/Maintenance. Discussion: There are two approaches that can be used for the initial selection of controls: a baseline control selection approach, or an organization-generated control selection approach. The baseline control selection approach uses control baselines, which are pre-defined sets of controls specifically assembled to address the protection needs of a group, organization, or community of interest. Control baselines serve as a starting point for the protection of individuals' privacy, information, and information systems. Federal control baselines are provided in [SP 800-53B]. The system security categorization (see Task C-2) and the security requirements derived from stakeholder protection needs, laws, executive orders, regulations, policies, directives, instructions, and standards (see Task P-15) can help inform the selection of security control baselines. A privacy risk assessment (see Task P-14) and privacy requirements derived from stakeholder protection needs, laws, executive orders, regulations, policies, directives, instructions, and standards (see Task P-15) can help inform the selection of privacy control baselines. Privacy programs use security and privacy control baselines to manage the privacy risks arising from both unauthorized system activity or behavior, as well as from authorized activities. After the pre-defined control baseline is selected, organizations tailor the baseline in accordance with the guidance provided (see Task S-2). The baseline control selection approach can provide consistency across a broad community of interest. The organization-generated control selection approach differs from the baseline selection approach because the organization does not start with a pre-defined set of controls. Rather, the organization uses its own selection process to select controls. This may be necessary when the system is highly specialized (e.g., a weapons system or a medical device) or has limited purpose or scope (e.g., a smart meter). In these situations, it may be more efficient and cost-effective for an organization to select a specific set of controls for the system (i.e., a bottom-up approach) instead of starting with a pre-defined set of controls from a broad-based control baseline and subsequently eliminating controls through the tailoring process (i.e., top-down approach). In both the baseline control selection approach and organization-generated control selection approach, organizations develop a well-defined set of

security and privacy requirements using a life cycle-based systems engineering process (e.g., [ISO 15288] and [SP 800-160 v1] as described in the RMF Prepare- System Level step, Task P-15. This process generates a set of requirements that can be used to guide and inform the selection of a set of controls to satisfy the requirements (whether the organization starts with a control baseline or generates the set of controls from its own selection process). Similarly, organizations can use the [NIST CSF] to develop Cybersecurity Framework Profiles representing a set of organization-specific security and privacy requirements and thus, guiding and informing control selection from [SP 800-53]. Tailoring may also be required in the organization-generated control selection approach (see Task S-2). Organizations do not need to choose one approach for the selection of controls for each of their systems, but instead, may use different approaches as circumstances dictate. References: [FIPS 199]; [FIPS 200]; [SP 800-30]; [SP 800-53]; [SP 800-53B]; [SP 800-160 v1] (System Requirements Definition, Architecture Definition, and Design Definition Processes); [SP 800-161] (Respond and Chapter 3); [IR 8062]; [IR 8179]; [CNSSI 1253]; [NIST CSF] (Core [Identify, Protect, Detect, Respond, Recover Functions]; Profiles). CONTROL TAILORING TASK S-2 Tailor the controls selected for the system and the environment of operation.

Basic Safeguarding of Covered Contractor Information Systems. As prescribed in 4.404-3, insert the following clause: Basic Safeguarding of Covered Contractor Information Systems (DATE) (a) * * * Covered contractor information system means an information system owned or operated by a contractor on which the contractor processes, stores, or transmits covered Federal information. Covered Federal information means information provided by or created for the Government when that information is other than (1) Simple transactional information (such as that necessary to process payments); (2) Information already publicly released (such as on public websites), or marked for public release, by the Government; (3) Federally-funded basic and applied research in science, technology, and engineering at colleges, universities, and laboratories in accordance with National Security Decision Directive 189; (4) Controlled unclassified information (CUI); or (5) Classified information. Information means any communication or representation of knowledge such as facts, data, or opinions, in any medium or form, including textual, numerical, graphic, cartographic, narrative, electronic, or audiovisual forms (OMB Circular A-130, Managing Information as a Strategic Resource). * * * * * (b) * * * (3) Identification of covered Federal information. While covered Federal information is not required to be marked or identified by the Government, some administrative markings (e.g., draft, deliberative process, predecisional, not for public release) can indicate that the information is covered Federal information. If the Contractor is not sure whether specific information is covered Federal information, the Contractor can request clarification from the Contracting Officer. * * * * * 41. Add sections 52.204-WW, 52.204-XX, and 52.204-YY to read as follows: 52.204-WW Notice of Controlled Unclassified Information Requirements. As prescribed in 4.403-7(a), insert the following provision: Notice of Controlled Unclassified Information Requirements (DATE) (a) Definitions. As used in this provision, contractor-attributional information, contractor bid or proposal information, controlled unclassified information (CUI), CUI incident, and handling have the meaning provided in the clause 52.204-XX, Controlled Unclassified Information. (b) Government-provided information. (1) The Offeror shall not use Government-provided information for its own purposes, whether or not the information is marked as CUI, unless the information is in the public domain, or unless the information was lawfully made available to the Offeror by someone other than the Government. (printed page 4297) (2) If Offerors require access to CUI, the Government will provide agency procedures on handling the CUI to ensure compliance with the requirements in 32 CFR part 2002. Offerors shall comply with these agency procedures when handling CUI. (c) Offeror-provided information.

From the NIST SP 800-172 Rev 3 Final Public Draft: The impact value for CUI is no less than moderate. 12 In accordance with 32 CFR 2002 [5], CUI is categorized at no less than the FIPS 199 [6] moderate confidentiality impact value. However, when federal law, regulation, or government-wide policy establishing the control of CUI specifies controls that differ from those of the moderate control baseline, then the applicable law, regulation, or government-wide policy is followed. The security requirements in SP 800-171 [12] have been satisfied to provide the foundational level of protection for CUI. Additional safeguards are necessary to protect CUI that is associated with critical programs or high value assets.13 13 Additional protections are required to protect CUI that is associated with critical programs and high value asset

Accordingly, in paragraph (2), we propose to revise the description of transmission media to

recognize that data is transmitted almost exclusively in electronic form today. The limited exception to this would be data that is handwritten on paper and hand-delivered or mailed, such that the data is never on electronic storage material. Additionally, the Department proposes to include public networks in the examples of transmission media and to remove the sentence that describes transmissions that are not considered transmissions via electronic media. By making these changes, we would reflect technology's evolution since 2013. We also propose to make a technical correction to paragraph (2) of the definition, consistent with a revision made in the 2013 Omnibus Rule to paragraph (1). [345] Specifically, the Department proposes to replace the term "electronic storage media" with "electronic storage material" in paragraph (2) to clarify the connection between definitions of electronic storage material and transmission media. We neglected to make this change in 2013 when we replaced "electronic storage media" with "electronic storage material" in paragraph (1), which means that paragraph (2) relies on a term that is no longer defined. This technical correction we propose is consistent with how the Department has interpreted the definition of transmission media and the connection between it and electronic storage material since the change was made in 2013.

4. Request for Comment The Department requests comment on the foregoing proposals, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular:

- a. Whether the proposed modifications accurately capture current use of electronic media.
- b. Whether the proposed modifications allow for future technological innovation.
- c. Whether there are other types of electronic storage material that the Department should include in the non-exhaustive list of examples.
- d. Whether there are other types of transmission media that the Department should include in the non-exhaustive list of examples.

B. Section 164.304-Definitions

means an information system that performs or controls a function, either in whole or in part, as an integral element of a larger system or subsystem, such as, ground support equipment, flight simulators, engine test stands, or fire control systems. Empowered official is defined in 22 CFR part 120 . Entity is a generic and comprehensive term which may include sole proprietorships, partnerships, corporations, limited liability companies, societies, associations, institutions, contractors, licensees, grantees, certificate holders, and other organizations usually established and operating to carry out a commercial, industrial, educational, or other legitimate business, enterprise, or undertaking, or parts of these organizations. It may reference an entire organization, a prime contractor, parent organization, a branch or division, another type of sub-element, a sub-contractor, subsidiary, or other subordinate or connected entity (referred to as "sub-entities" when necessary to distinguish such entities from prime or parent entities). It may also reference a specific location or facility, or the headquarters or official business location of the organization, depending upon the organization's business structure, the access needs involved, and the responsible CSA's procedures. The term "entity" as used in this rule refers to the particular entity to which an agency might release, or is releasing, classified information, whether that entity is a parent or (printed page 83316) subordinate organization. The term "entity" in this rule includes contractors. Entity eligibility determination means an assessment by the CSA as to whether an entity is eligible for access to classified information of a certain level (and all lower levels). Entity eligibility determinations may be broad or limited to specific contracts, sponsoring agencies, or circumstances. A favorable entity eligibility determination results in eligibility to access classified information under the cognizance of the responsible CSA to the level approved. When the entity would be accessing categories of information such as RD or SCI for which the CSA for that information has set additional requirements, CSAs must also assess whether the entity is eligible for access to that category of information. Some CSAs refer to their favorable entity eligibility determinations as FCLs. However, a favorable entity eligibility determination for the DHS CCIPP is not equivalent to an FCL and does not meet the requirements for FCL reciprocity. A favorable entity eligibility determination does not convey authority to store classified information. Escort means a cleared person, designated by the contractor, who accompanies a shipment of classified material to its destination. The classified material does not remain in the personal possession of the escort but the conveyance in which the material is transported remains under the constant observation and control of the escort. Extent of protection

- Compromised workload (application) container (e.g., via a supply chain attack) - Compromised node L4 proxy or container network interface (CNI) - Compromised node L7 proxy - Compromised node with limited privileged access (e.g., a container breakout) - Root compromise of node (e.g., a container breakout chained with the exploitation of a privilege escalation vulnerability) - Network access to the Kubernetes API server Threat Description : A compromised application container (e.g., via a

supply chain attack during the development phase) leads to a takeover of the identity associated with that application. Threat Description : A compromised application container (e.g., via a supply chain attack during the development phase) leads to a takeover of the identity associated with that application.

In addition to specific routine uses which are listed in the applicable Army system of record notices, certain 'Blanket Routine Uses' apply to all DOD maintained systems of records. These are listed on the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy/>. These 'Blanket Routine Uses' are not specifically listed in each system of records notice as the specific routine uses are. The current DOD 'Blanket Routine Uses' are as follows: (1) Law Enforcement Routine Use. If a system of records maintained by a DOD component to carry out its functions indicates a violation or potential violation of law, whether civil, criminal or regulatory in nature, and whether arising by general statute or by regulation, rule, or order issued pursuant thereto, the relevant records in the system of records may be referred, as a routine use, to the agency concerned, whether federal, state, local, or foreign, charged with the responsibility of investigating or prosecuting such violation or charged with enforcing or implementing the statute, rule, regulation or order issued pursuant thereto. (2) Disclosure When Requesting Information Routine Use. A record from a system of records maintained by a DOD component may be disclosed as a routine use to a Federal, State, or local agency maintaining civil, criminal, or other relevant enforcement information or other pertinent information, such as current licenses, if necessary to obtain information relevant to a DOD Component decision concerning the hiring or retention of an employee, the issuance of a security clearance, the letting of a contract, or the issuance of a license, grant or other benefit. (3) Disclosure of Requested Information Routine Use. A record from a system of records maintained by a DOD component may be disclosed to a Federal agency, in response to its request, in connection with the hiring or retention of an employee, the issuance of a security clearance, the reporting of an investigation of an employee, the letting of a contract, or the issuance of a license, grant, or other benefit by the requesting agency, to the extent that the information is relevant and necessary to the requesting agency's decision on the matter. (4) Congressional Inquiries Disclosure Routine Use. Disclosure from a system of records maintained by a DOD component may be made to a congressional office from the record of an individual in response to an inquiry from the congressional office made at the request of that individual. (5) Private Relief Legislation Routine Use. Relevant information contained in all systems of records of DOD published on or before August 22, 1975, may be disclosed to Office of Management and Budget in connection with the review of private relief legislation, as set forth in OMB Circular A-19, at any stage of the legislative coordination and clearance process as set forth in that Circular. (6) Disclosures Required by International Agreements Routine Use.

In this manual security information is provided about your PBX and adjunct systems. Adjunct systems are processors, access devices, or any related piece of equipment that supports PBX or voice mail system operation, maintenance, or administration. The schematics included in this manual provide some background information on the interconnection of these pieces of equipment. Remote Maintenance, Administration and Traffic System. Social engineering refers to a person's ability to use personality, knowledge of human nature, and social skills to steal toll calls. In one scheme, a hacker calls a long distance subscriber and claims to represent his/her long distance carrier. The hacker might claim to be doing maintenance or validating long distance access codes (PINs). He reads the first ten digits of the access code (which is the phone number of the person he is talking to) and makes up the last four digits. Human nature being what it is, the victim automatically corrects the hacker, giving him the correct PIN. The hacker thanks the subscriber and hangs up in full possession of a valid authorization code for placing long distance calls.

These standards and guidelines. - Performed research and conducted outreach on standards, practices, and technologies to enable prompt and effective computer security incident handling and coordination. - Continued the successful collaboration with the Office of the Director of National Intelligence (ODNI), the Committee on National Security Systems (CNSS). These trends have caused federal departments and agencies to have a lack of visibility and understanding throughout the supply chain of how the technology being acquired is developed, integrated and deployed, as well as the processes, procedures, and practices used to assure the integrity, security, resilience, and quality of the products and services. This lack of visibility and understanding, in turn, has decreased the control that federal departments and agencies have with regard to the decisions impacting the inherited risks traversing the supply chain and the ability to effectively manage

those risks. Figure 4 (below) shows how ICT supply-chain risk may be derived from adversarial or non-adversarial threats, as well as external or internal vulnerabilities. The likelihood of an event and the potential impact of an event are also key factors.

(1) The records in all systems of records maintained in accordance with the OPM Government-wide system notices are technically only in the temporary custody of the Department of Defense. (2) All requests for access to these records must be processed in accordance with 5 CFR part 297 as well as applicable Component procedures. (printed page 18769) (3) When a DoD Component refuses to grant access to a record in an OPM system, the Component shall advise the individual that his or her appeal must be directed to the Assistant Director for Workforce Information, Personnel Systems and Oversight Group, U.S. Office of Personnel Management, 1900 E Street, NW., Washington, DC, in accordance with the procedures of 5 CFR part 297 . §-310.19 Amendment of records. (a) Individual review and correction. Individuals are encouraged to review the personal information being maintained about them by the DoD Components periodically and to avail themselves of the procedures established by this part and other Regulations to update their records. (b) Amending records. (1) An individual may request the amendment of any record contained in a system of records pertaining to him or her unless the system of records has been exempted specifically from the amendment procedures of this part under paragraph (b) of §-310.26. Normally, amendments under this part are limited to correcting factual matters and not matters of official judgment, such as performance ratings, promotion potential, and job performance appraisals. (2) While a Component may require that the request for amendment be in writing, this requirement shall not be used to discourage individuals from requesting valid amendments or to burden needlessly the amendment process. (3) A request for amendment must include: (i) A description of the item or items to be amended; (ii) The specific reason for the amendment; (iii) The type of amendment action sought (deletion, correction, or addition); and (iv) Copies of available documentary evidence supporting the request. (c) Burden of proof. The applicant must support adequately his or her claim. (d) Identification of requesters. (1) Individuals may be required to provide identification to ensure that they are indeed seeking to amend a record pertaining to themselves and not, inadvertently or intentionally, the record of others. (2) The identification procedures shall not be used to discourage legitimate requests or to burden needlessly or delay the amendment process. (See paragraph (c) of §-310.17.) (e) Limits on attacking evidence previously submitted. (1) The amendment process is not intended to permit the alteration of records presented in the course of judicial or quasi-judicial proceedings. Any amendments or changes to these records normally are made through the specific procedures established for the amendment of such records.

The DoD is implementing a phased implementation for the revised CMMC Program and intends to introduce CMMC Status requirements in solicitations over a three-year period to provide appropriate ramp-up time. This phased implementation is intended to minimize the financial impacts to defense contractors, especially small businesses, and disruption to the existing DoD supply chain. After CMMC is implemented in acquisition regulation, DoD will include CMMC self-assessment requirements in solicitations and resulting contracts when warranted by the type of information that will be handled by the contractor of subcontractor(s). CMMC Status requirements for Levels 1, 2, and 3 will be included in solicitations and resulting contracts issued after the phase-in period when warranted by any FCI and/or CUI information protection requirements for the contract effort. In the intervening period, Government Program Managers will have discretion to include CMMC Status requirements or exclude them and rely upon existing DFARS clause 252.204-7012 requirements, in accordance with DoD policy. As stated in §-170.20(a), there is qualified standards acceptance between DCMA DIBCAC High Assessment and the CMMC Status of Level 2(C3PAO), which will result in staggering of the dates for new Level 2 certification assessments. The implementation period will consist of four (4) phases as set forth in §-170.3(e), during which time the Government will include CMMC requirements in certain solicitations and contracts. During the CMMC phase-in period, program managers and requiring activities will be required to include CMMC Status requirements in certain solicitations and contracts and will have discretion to include in others. A purpose of the phased implementation is to ensure adequate availability of authorized or accredited C3PAOs and assessors to meet the demand. Revised CMMC Program Flow Down CMMC Level requirements will be flowed down to subcontractors at all tiers as set forth in §-170.23; however, the specific CMMC Status required for a subcontractor will be based on the type of unclassified information and the priority of the acquisition program and/or technology being developed. Key Changes Incorporated in the Revised CMMC Program In November 2021, the Department announced the revised CMMC Program, which is an updated program structure with revised requirements. In the revised CMMC Program, the Department has introduced several key changes

that build on and refine the original program requirements. These include: Streamlining the model from five levels to three levels. Exclusively implementing National Institute of Standards and Technology (NIST) cybersecurity standards and guidelines. Allowing all companies subject to Level 1, and a subset of companies subject to Level 2 to demonstrate compliance through self-assessments. Increased oversight of professional and ethical standards of CMMC third-party assessors.

CMMC Level 2 self-assessment, Level 2 certification assessment, and Level 3 certification assessment are valid for a defined CMMC Assessment Scope as outlined in § 170.19 CMMC Scoping. A new CMMC assessment may be required if significant architectural or boundary changes are made to the previous Assessment Scope. Examples include, but are not limited to, expansions of networks or mergers and acquisitions. Operational changes within an Assessment Scope, such as adding or subtracting resources within the existing assessment boundary that follow the existing SSP do not require a new assessment, but rather are covered by the annual affirmations to the continuing compliance with requirements. The DoD did not accept the recommendation to change the criteria for POA&Ms or the timeline allowed to remediate open POA&M items. The 180-day timeline and the determination of the weighted practices that may be included in a POA&M were risk-based decisions. The determination factored the relative risk DoD is willing to accept when a particular practice is Not Met and the amount of risk the DoD is willing to accept for those security practices that remain ·NOT MET· for an extended period. Unlike the original CMMC Program, the revised CMMC Program accepts some risk with the use of limited POA&Ms. There is value to the DoD in having the pre-assessment information in CMMC eMASS for overall program management and oversight. The information indicates that an assessment is either scheduled or in-process. The CMMC PMO seeks to track CMMC Program adoption, and the pre-assessment information allows reporting on upcoming assessments. Based on the DoD's cost analysis, the cost to upload pre-assessment material is minimal. The rule and Hashing Guide have been updated to add clarity that only reporting a single hash is required, and the name of the hash algorithm used needs to be stored in CMMC eMASS. Each Assessment Objective in NIST SP 800-171A Jun2018 must yield a finding of MET or NOT APPLICABLE for the overall security requirement to be scored as MET. Assessors exercise judgment in determining when sufficient and adequate evidence has been presented to make an assessment finding. This is consistent with current DIBCAC High Assessments and assessments conducted under the Joint Surveillance Voluntary Assessment (JSVA) program. A security requirement can be applicable, even with assessment objectives that are N/A. The security requirement is NOT MET when one or more applicable assessment objectives is NOT MET. The requirements of each Level of the CMMC Model are defined in sections §§ 170.15 through 170.18 and the scoring of assessments is described in § 170.24. The assessment frequency required is every year for a CMMC Status of Final Level 1 (Self), (printed page 83199) and every 3 years for a CMMC Statuses of Final Level 2 (Self), Final Level 2 (C3PAO), and Final Level 3 (DIBCAC), or when changes within the CMMC Assessment Scope invalidate the assessment.

HIPAA Security Rule section 164.308 (Administrative Safeguards) addresses business associate contracts. Covered entities and business associates must implement appropriate safeguards to protect electronic protected health information (ePHI). For business associate contracts, organizations should: 1. Establish and document policies specific to business associate contracts 2. Implement technical and procedural controls 3. Train workforce members on their responsibilities 4. Conduct periodic risk assessments addressing business associate contracts 5. Maintain documentation of compliance efforts Under 45 CFR 164.308, this is a administrative safeguards requirement that applies to all covered entities and business associates that create, receive, maintain, or transmit ePHI.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 ENHANCED SECURITY REQUIREMENT
ORGANIZATION-DEFINED PARAMETER 03.12.04E [Assignment: organization-defined conditions] 03.12.04E
[Assignment: organization-defined frequency] 03.13.01E [Assignment: organization-defined system
components] 03.13.02E [Assignment: organization-defined techniques] 03.13.03E [Assignment:
organization-defined concealment and misdirection techniques] 03.13.04E [Assignment: organization-
defined system components] 03.13.05E [Assignment: organization-defined processing and/or storage]
03.13.05E [Selection (one): [Assignment: organization-defined time frequency]; at random time
intervals] 03.13.06E [Assignment: organization-defined platform-independe

means information that the Government creates or possesses, or that an entity creates or possesses for or on behalf of the Government, that a law, regulation, or Governmentwide policy requires or

ot recommended metrics. They are included to assist in explaining the concept of metrics as they are applied across tiers. Organizations define their own metrics and associated monitoring frequencies. In order to calculate metrics, associated controls and/or their objects are assessed and monitored with frequencies consistent with the timing requirements expressed in the metric.

The contribution to baseline traceback speeds by each sector is adjusted to reflect the probability that the food was contaminated further up the supply chain. Based on conversations with traceback personnel, we estimated that 10 percent of outbreaks requiring traceback records are from contamination at manufacturing facilities, and 90 percent are from contamination at the farm facilities (which may include mixed-type facilities subject to the recordkeeping requirements of this final rule).

a. Adjustments to traceback performance for the grocery sector . The baseline contribution from the retail sector to traceback performance is composed of contributions from both the restaurant and grocery sectors. The contribution to traceback performance from grocery outlets represents only a fraction of the total contribution of the retail sector. We adjust the probability of requiring traceback records from grocery outlets downward to account for the possibility that initial traceback from retail could begin at a restaurant as well as at a grocery outlet. For the adjustment we use the estimated number of restaurant locations of approximately 900,000 reported in

a recent survey conducted for the National Restaurant Association (Ref. 16). b. Adjustments to traceback performance for transportation and warehouse facilities . We adjusted estimates of the contributions to traceback performance by warehouse and transportation facilities to reflect the nature of traceback records from these facilities for many investigations. Manufacturers and third party warehouses are both important links in the supply chain and are required to keep records under the provisions of this regulation. This requirement allows FDA to determine whether what was sent at each stage is what was received, and if not, to be able to locate the unaccounted-for food. It is critical that FDA be able to locate and remove from commerce any adulterated food that presents a credible threat of serious adverse health consequences or death to humans or animals. We assume that there is a uniform likelihood between zero and one that there are more than two transportation or warehouse facilities used in the provision of a transportation or storage service. For these cases there is no adjustment to the value of records from such facilities during a traceback investigation. When two or fewer facilities provide transportation and warehouse services (estimated to be approximately half of the total number of such services) we adjust downward the value of records to acknowledge their role of verifying, rather than identifying, the buyer or seller of the food. For these cases we adjust the value of records to traceback performance by a factor of 0.5. c. Adjustments to traceback performance for large and very small facilities

SPRS is an existing DoD database that is compliant with DoD regulations, which includes meeting Privacy requirements. DoD suppliers are already required to use SPRS to record NIST SP 800-171 self-assessment scores, as referenced in DFARS clause 252.204-7020. The CMMC rule expands the use of SPRS to include CMMC Status, certification assessment scores, and affirmations. SPRS is the tool that the DoD acquisition workforce will use to verify companies meet CMMC requirements to be eligible for contract award. SPRS data entry does not make available to Contracting Officers scoring of individual security requirements. The DoD does not concur with granting prime contractors access to view the CMMC scores or Certificates of CMMC Status for potential subcontractors in SPRS. Subcontractors may voluntarily share their CMMC Status, assessment scores, or certificates to facilitate business teaming arrangements. Changing access to PIEE and SPRS is outside the scope of this rule. CMMC eMASS is a tailored, stand-alone instantiation of eMASS for use by authorized representatives from C3PAOs, the DCMA DIBCAC, and the CMMC PMO. Individuals from each C3PAO will have access to CMMC eMASS to upload Level 2 assessment data. DCMA DIBCAC personnel will have access to CMMC eMASS to upload Level 3 assessment data. OSAs will not have access to CMMC eMASS. Authorized personnel from OSAs may access SPRS, which will host assessment certification and self-assessment data, and will be able to upload and view scores only for their OSA. The DOD declines to add requirements for submitting self-assessments in eMASS. The requirement is for the OSA to enter scores into SPRS. There is value to the DoD in having the pre-assessment information in CMMC eMASS for overall program management and oversight. The information indicates that an assessment is either scheduled or in-process. The CMMC PMO seeks to track CMMC program adoption, and pre-assessment information allows reporting on upcoming assessments. Based on the DoD cost analysis, the effort to upload pre-assessment material is minimal. DoD Program Managers are not responsible for uploading data into eMASS, nor do they have any responsibility regarding the data uploaded to eMASS by DCMA. An ESP, OSA, or OSC seeking CMMC assessment will need a CAGE code and an account in SPRS to complete the annual attestation required of all CMMC certified or CMMC compliant organizations. An OSA/OSC must obtain a CAGE code via <https://sam.gov> before registering in PEE. Step by Step instructions for how to obtain an account can be found on the PEE Vendor Account website: <https://piee.eb.mil/·xhtml/·unauth/·web/·homepage/·vendorGettingStartedHelp.xhtml> . CAGE codes (or NCAGE codes for non-US-based companies) are also required. US-based contractors obtain a Commercial and Government Entity (CAGE) code from <https://cage.dla.mil/·Home/·UsageAgree> . Businesses outside of the US must obtain a NATO Commercial and Government Entity (NCAGE) code from

From the NIST SP 800-172 Rev 3 Final Public Draft: values can be guided and informed by laws, Executive Orders, directives, regulations, policies, standards, guidance, or mission and business needs. Once specified, the values for the OD Ps become part of the requirement. A discussion section is included with each requirement. It is derived from the control discussion section in SP 800-53 [8] and provides additional information to facilitate the implementation and assessment of the requirement. The discussion section is informative, not normative. It is not intended to extend the scope of a requirement or influence the solutions that organizations may implement to satisfy a requirement. The use of examples is notional, not exhaustive, and does not reflect the potential options available to organizations. If applicable, the sec

The responsibility of federal agencies to protect CUI does not change when such information is shared with nonfederal organizations. 4 A nonfederal organization is any entity that owns, operates, or maintains a nonfederal system. Therefore, a similar level of protection is needed when CUI is processed, stored, or transmitted by nonfederal organizations using nonfederal systems. The requirements for protecting CUI in nonfederal systems and organizations must comply with Federal Information Processing Standards (FIPS) 199 [6] and FIPS 200 [7] to maintain a consistent level of protection. The requirements are derived from the controls in NIST Special Publication (SP) 800-53 [8]. In certain situations, CUI may be associated with a critical program

Although CMMC compliance may add to an organization's cost, no member of the DIB can assume the status-quo in today's ever-changing cybersecurity environment. Increasing costs to protect the nation's data and industries from emerging threats is simply a component of doing business anywhere in the world. Processing, storing, or transmitting sensitive Government information comes with a handling cost that needs to be built into each organization's business model. All contractors or sub-contractors with access to CUI need to be capable of protecting that information to the standards specified in 32 CFR part 2002. If a small business cannot comply with the requirements of DFARS clause 252.204-7012 and NIST SP 800-171 R2, then that business should not receive CUI or process, store, or transmit CUI. If the DoD information flowed by the prime to a subcontractor is only FCI, then only a CMMC Level 1 self-assessment is required for the subcontractor prior to the flow of information under contract. DoD's programs, technological superiority, and best interests are not served if FCI and CUI are not consistently and adequately safeguarded by all who process, store, or transmit it. 2. Cost Benefit. Some commenters suggested it would be more cost effective for DoD to provide an environment or a DoD managed portal for the handling of CUI. A significant concern expressed was that companies have delayed complying with DoD cybersecurity standards until the CMMC rule was released and they could understand what level of compliance they will require. Several commenters felt DoD underestimated the costs and should have include the implementation cost of the requirements in this rule as well. One commenter was confused about how the discount rates were applied. Another commenter suggested that DoD provide flexibility to allow small businesses to not meet all the requirements and still be allowed to handle CUI and another expressed concerns regarding the cost of compliance and the degradation of the DIB that will be unable to afford compliance. DoD Response: The DoD declined to adopt the alternatives suggested in the comments, such as policy-based solutions that lack a rigorous assessment component or sharing CUI only through DoD-hosted secure platforms. The current DFARS clause 252.204-7012 requires protection of Security Protection Assets (SPA) and Security Protection Data (SPD). Section 1.1 of NIST SP 800-171 R2 states: "The requirements apply only to components of nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components." There is therefore no increase in the scope because of the CMMC Program as described in the rule. SPD requires protection commensurate with the CUI it protects and is based on how and where the SPD is stored. The FedRAMP requirements for handling SPD are therefore the same as that for handling CUI.

(a) OSAs conduct a self-assessment based on NIST guidelines as addressed in § 170.16. This is an assessment to validate implementation of the 110 security requirements from NIST SP 800-171 Rev 2. (b) OSAs upload assessment results and affirmations in SPRS in accordance with § 170.16 and § 170.22. (c) OSAs may have a POA&M at CMMC Level 2 as addressed in § 170.21(a)(2). OSAs must perform a POA&M closeout self-assessment and post compliance results in SPRS in accordance with § 170.16. CMMC Level 2 Certification Assessment Collection The Level 2 Certification Assessment information collection reporting and recordkeeping requirements are included in this part with the exception of the requirement for the OSC to upload the affirmation in SPRS that will be included in the Title 48 acquisition rule and an update to the DFARS collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Additionally, the information collection reporting requirements for the CMMC instantiation of eMASS are included in a separate information collection request (ICR) for this part and cover only those requirements pertaining to the CMMC process. The information collection reporting requirements for eMASS include: The Accreditation Body provides the CMMC PMO with current data on C3PAOs, including authorization and accreditation records and status using the CMMC instantiation of eMASS as addressed in § 170.8(b)(9). C3PAOs submit pre-assessment and planning material, final assessment reports, and appropriate CMMC certificates of assessment into the CMMC instantiation of eMASS as addressed in § 170.9(b)(8). C3PAOs upload assessment data compliant with the CMMC assessment data standard into the CMMC instantiation of eMASS as addressed in § 170.9(b)(18). C3PAOs post POA&M closeout assessment compliance results into the CMMC instantiation of eMASS in accordance with

§ 170.17(a)(1)(ii)(B) of this part. C3PAOs upload artifacts (list of artifacts, hash of artifacts, and hashing algorithm used) into the CMMC instantiation of eMASS as addressed in § 170.9(b)(18) of this part. C3PAOs submit assessment appeals, review records, and decision results of assessment appeals using the CMMC instantiation of eMASS as addressed in § 170.9(b)(21) of this part. Additional information collection reporting and recordkeeping requirements for this part include: OSCs prepare for assessments based on NIST guidelines as addressed in § 170.17. C3PAOs conduct assessments based on NIST guidelines as addressed in § 170.17. This is an assessment to validate implementation of the 110 security requirements from NIST SP 800-171 Rev 2. Prospective C3PAOs must complete and submit the Standard Form (SF) 328 Certificate Pertaining to Foreign Interests upon request from Defense Counterintelligence and Security Agency (DCSA) (OMB Control Number 0704-0579). OSCs may have a POA&M at CMMC Level 2 as addressed in § 170.21(a)(2). C3PAOs must perform a POA&M closeout assessment.

| Introduction | 4-8 | | b. | Automated Information and Applications | 4-8 | | c. | Computer Systems | 4-8 | | 403 | Protection Measure Baseline Considerations | Protection Measure Baseline Considerations | 4-10 | | | a. | Sensitivity/Criticality Level 0 | 4-10 | | | b. | Sensitivity/Criticality Level 1 | 4-11 | | | c. | Sensitivity/Criticality Level 2 | 4-11 | | | d. | Sensitivity/Criticality Level 3 | 4-12 | | | CHAPTER 5. COMPUTER SECURITY PLANNING | CHAPTER 5. COMPUTER SECURITY PLANNING | | 500 | Introduction | Introduction | 5-1 | | 501 | Headquarters Computer Security Planning | Headquarters Computer Security Planning | 5-1 | | | a. | NASA Automated Information Security Program Plan | 5-1 | | | b. | Program Office Computer Security Plan (PO-CSP) | 5-2 | | 502 | Center Computer Security Planning | Center Computer Security Planning | 5-3 | | | a. | Center Computer Security Plan (CCSP) | 5-3 | | | b. | Content and Format | 5-4 | | 503 | DPI | Computer Security Planning | 5-6 | | | a.

§ 164.308 Administrative safeguards. (a) A covered entity or business associate must, in accordance with § 164.306 : (1) (i) Standard: Security management process. Implement policies and procedures to prevent, detect, contain, and correct security violations. (ii) Implementation specifications: (A) Risk analysis (Required). Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the covered entity or business associate. (B) Risk management (Required). Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with § 164.306(a) . (C) Sanction policy (Required). Apply appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity or business associate. (D) Information system activity review (Required). Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports. (2) Standard: Assigned security responsibility. Identify the security official who is responsible for the development and implementation of the policies and procedures required by this subpart for the covered entity or business associate. (3) (i) Standard: Workforce security. Implement policies and procedures to ensure that all members of its workforce have appropriate access to electronic protected health information, as provided under paragraph (a)(4) of this section, and to prevent those workforce members who do not have access under paragraph (a)(4) of this section from obtaining access to electronic protected health information. (ii) Implementation specifications: (A) Authorization and/or supervision (Addressable). Implement procedures for the authorization and/or supervision of workforce members who work with electronic protected health information or in locations where it might be accessed. (B) Workforce clearance procedure (Addressable). Implement procedures to determine that the access of a workforce member to electronic protected health information is appropriate. (C) Termination procedures (Addressable). Implement procedures for terminating access to electronic protected health information when the employment of, or other arrangement with, a workforce member ends or as required by determinations made as specified in paragraph (a)(3)(ii)(B) of this section. (4) (i) Standard: Information access management. Implement policies and procedures for authorizing access to electronic protected health information that are consistent with the applicable requirements of subpart E of this part . (ii) Implementation specifications: (A) Isolating health care clearinghouse functions (Required). If a health care clearinghouse is part of a larger organization, the clearinghouse must implement policies and procedures that protect the electronic protected health information of the clearinghouse from unauthorized access by the larger organization. (B) Access authorization (Addressable). Implement policies and procedures for granting access to electronic protected health information, for example, through access to a workstation, transaction, program, process, or other mechanism. (C) Access establishment and

modification (Addressable). Implement policies and procedures that, based upon the covered entity's or the business associate's access authorization policies, establish, document, review, and modify a user's right of access to a workstation, transaction, program, or process. (5) (i) Standard: Security awareness and training. Implement a security awareness and training program for all members of its workforce (including management). (ii) Implementation specifications. Implement: (A) Security reminders (Addressable). Periodic security updates. (B) Protection from malicious software (Addressable). Procedures for guarding against, detecting, and reporting malicious software. (C) Log-in monitoring (Addressable). Procedures for monitoring log-in attempts and reporting discrepancies. (D) Password management (Addressable). Procedures for creating, changing, and safeguarding passwords. (6) (i) Standard: Security incident procedures. Implement policies and procedures to address security incidents. (ii) Implementation specification: Response and reporting (Required). Identify and respond to suspected or known security incidents; mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity or business associate; and document security incidents and their outcomes. (7) (i) Standard: Contingency plan. Establish (and implement as needed) policies and procedures for responding to an emergency or other occurrence (for example, fire, vandalism, system failure, and natural disaster) that damages systems that contain electronic protected health information. (ii) Implementation specifications: (A) Data backup plan (Required). Establish and implement procedures to create and maintain retrievable exact copies of electronic protected health information. (B) Disaster recovery plan (Required). Establish (and implement as needed) procedures to restore any loss of data. (C) Emergency mode operation plan (Required). Establish (and implement as needed) procedures to enable continuation of critical business processes for protection of the security of electronic protected health information while operating in emergency mode. (D) Testing and revision procedures (Addressable). Implement procedures for periodic testing and revision of contingency plans. (E) Applications and data criticality analysis (Addressable). Assess the relative criticality of specific applications and data in support of other contingency plan components. (8) Standard: Evaluation. Perform a periodic technical and nontechnical evaluation, based initially upon the standards implemented under this rule and, subsequently, in response to environmental or operational changes affecting the security of electronic protected health information, that establishes the extent to which a covered entity's or business associate's security policies and procedures meet the requirements of this subpart. (b) (1) Business associate contracts and other arrangements. A covered entity may permit a business associate to create, receive, maintain, or transmit electronic protected health information on the covered entity's behalf only if the covered entity obtains satisfactory assurances, in accordance with § 164.314(a) , that the business associate will appropriately safeguard the information. A covered entity is not required to obtain such satisfactory assurances from a business associate that is a subcontractor. (2) A business associate may permit a business associate that is a subcontractor to create, receive, maintain, or transmit electronic protected health information on its behalf only if the business associate obtains satisfactory assurances, in accordance with § 164.314(a) , that the subcontractor will appropriately safeguard the information. (3) Implementation specifications: Written contract or other arrangement (Required). Document the satisfactory assurances required by paragraph (b)(1) or (b)(2) of this section through a written contract or other arrangement with the business associate that meets the applicable requirements of § 164.314(a) . [68 FR 8376 , Feb. 20, 2003, as amended at 78 FR 5694 , Jan. 25, 2013]

- (3) When the Court orders the release of denied records, it may also issue a written finding that the circumstances surrounding the withholding raise questions as to whether DoD Component personnel acted arbitrarily and capriciously. In these cases, the special counsel of the Merit System Protection Board shall conduct an investigation to determine whether or not disciplinary action is warranted. The DoD Component is obligated to take the action recommended by the special counsel.
- (4) The Court may punish the responsible official for contempt when the DoD Component fails to comply with the court order to produce records that it determines have been withheld improperly, or to otherwise comply with a court order. (e) Non-United States Government source information (business information) . A requester may bring suit in a U.S. District Court to compel the release of records obtained from a submitter or records based on information obtained from a submitter. The submitter shall be notified promptly of the court action pursuant to E.O. 12600 . When the submitter advises that it is seeking court action to prevent release, the DoD Component shall defer answering or otherwise pleading to the (printed page 71862) complainant as long as permitted by the court, or until a decision is rendered in the court action of the source, whichever is sooner.
- (f) FOIA litigation . Personnel responsible for processing FOIA requests at the DoD Component

level shall be aware of litigation under the FOIA. Whenever a complaint is filed in a U.S. District Court under the FOIA, the DoD Component named in the complaint shall forward a copy of the complaint to DFOIPO with an information copy to the DoD Office of the General Counsel, ATTN: Office of Legal Counsel. Subpart E-Fee Schedule § 286.24 General provisions. (a) Application . (1) The fees described in this subpart apply to requests submitted pursuant to 5 U.S.C. 551 , 552 , and 552(a) and conform to the OMB Uniform Freedom of Information Act Fee Schedule and Guidelines S. They reflect direct costs for search, review (in the case of commercial requesters), and duplication of documents. (2) The fees are neither intended to imply they must be charged in connection with providing information to the public pursuant to the FOIA request nor are they meant to substitute for any other charges established by the Department of Defense, such as DoD 7000.14-R, to recoup direct costs of authorized services provided by DoD Components that are not FOIA related. (3) Nothing in this subpart shall supersede fees chargeable under a statute specifically providing for setting the level of fees for particular types of records, such as the GPO or the National Technical Information Service. The Components should ensure documents responsive to a request are maintained for distribution by agencies operating statutory-based fee schedule programs and inform requesters of the steps necessary to obtain records from those sources. (b) Fee restrictions

(n) ISO/IEC 17011:2017, titled ·Conformity assessment·Requirements for accreditation bodies accrediting conformity assessment bodies· specifies requirements for the competence, consistent operation and impartiality of accreditation bodies assessing and accrediting conformity assessment bodies. This document is incorporated by reference as a source for requirements on the CMMC Ecosystem. (o) ISO/IEC 17020:2012, titled ·Conformity assessment·Requirements for the operation of various types of bodies performing inspection· specifies requirements for the competence of bodies performing inspection and for the impartiality and consistency of their inspection activities. It applies to inspection bodies of type A, B or C, as defined in ISO/IEC 17020:2012, and it applies to any stage of inspection.· This document is incorporated by reference as a source for requirements on the CMMC Ecosystem. (p) ISO/IEC 17024:2012, titled ·Conformity assessment·Requirements for the operation of various types of bodies performing inspection· contains principles and requirements for a body certifying persons against specific requirements, and includes the development and maintenance of a certification scheme for persons.· This document is incorporated by reference as a source for requirements on the CMMC Ecosystem. Section 170.3·Applicability Section 170.3 identifies entities to which the rule applies and how the Department intends to implement the rule. The rule applies to defense contractors and subcontractors that will process, store, or transmit FCI or CUI, and private-sector businesses or other entities that are specified in Subpart C. Government information systems that are operated by contractors and subcontractors in support of the Government do not apply to this rule. CMMC Program requirements apply to DoD solicitations and contracts requiring defense contractors and subcontractors to process, store, or transmit FCI or CUI. Exceptions to the applicability of this rule are addressed in § 170.3(c)(1) and (2). Department Program Managers or requiring activities will determine which CMMC Level will apply to a contract or procurement. Applicability of the CMMC Level to subcontractors is addressed in § 170.23. Section 170.3 addresses the four-phased implementation plan of the CMMC Program requirements in solicitations and contracts. Phase 1 begins on the effective date of the CMMC revision to DFARS 252.204-7021. More information regarding Phase 1 can be found in § 170.3(e)(1). Phase 2 begins six months after the start date of Phase 1. More information regarding Phase 2 can be found in § 170.3(e)(2). Phase 3 begins one calendar year after the start date of Phase 2. More information regarding Phase 3 can be found in § 170.3(e)(3). Phase 4, or full implementation, begins one calendar year after the start date of Phase 3. More information regarding Phase 4 can be found in § 170.3(e)(4). Section 170.4·Acronyms and Definitions

From the NIST SP 800-172 Rev 3 Final Public Draft: In certain situations, CUI may be associated with a critical program 5 The definition of a critical program may vary from organization to organization. For example, the Department of Defense defines a critical program as one that significantly increases capabilities and mission effectiveness or extends the expected effective life of an essential system or capability [9]. or a high value asset.6 6 See OMB Memorandum M-19-03 [10]. These programs and assets are potential targets for the advanced persistent threat (APT). An APT is an adversary or adversarial group that possesses the expertise and resources that allow it to create opportunities to achieve its objectives by using multiple attack vectors, including cyber, physical, and deception. These objectives include establishing a

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.04.05E Dual Authorization for System Changes

993 Enforce dual authorization for implementing changes to [Assignment: organization-defined system components and system-level information]. **DISCUSSION** Dual authorization is also known as two-person control. Organizations employ dual authorization to help ensure that any changes to selected system components and system-level information cannot occur unless two qualified individuals approve and implement such changes. Requiring two individuals to implement system changes provides an increased level of assurance that the proposed changes are correct implementations of approved changes. The individuals are also accountable for the changes that have been implemented. To reduce the risk of collusion, organizations consider rotating du

From the NIST SP 800-172 Rev 3 Final Public Draft: Rather, detonation chambers are intended to quickly identify malicious code and either reduce the likelihood that the code is propagated to user environments of operation or prevent NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 such propagation completely. This requirement does not enhance a specific 2032

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 **INTENDED EFFECT IMPACT ON RISK EXPECTED RESULTS** Reduce Decrease the degree of damage from a threat event. The degree of damage can have two dimensions: breadth (i.e., number of affected resources) and depth (i.e., level of harm to a given resource). Reduce the level of impact. · The level of damage to mission or business operations due to adversary activities is reduced with partial restoration or the reconstitution of all affected resources. Example: Resources determined to be corrupted or suspect (integrity checks, behavior validation) are restored from older, uncorrupted resources (protected backup and restore) with reduced functionality. · The level of damage

· System Owner · Common Control Provider · Information Owner or Steward · System Security Officer · System Privacy Officer · Senior Agency Official for Privacy · Senior Agency Information Security Officer NIST SP 800-37, REVISION 2 RISK MANAGEMENT FRAMEWORK FOR INFORMATION SYSTEMS AND ORGANIZATIONS A System Life Cycle Approach for Security and Privacy

APPENDIX E PAGE 138 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-37r2> **RMF TASKS PRIMARY RESPONSIBILITY SUPPORTING ROLES TASK M-5 Security and Privacy Reporting** Report the security and privacy posture of the system to the authorizing official and other organizational officials on an ongoing basis in accordance with the organizational continuous monitoring strategy. · System Owner · Common Control Provider · Senior Agency Information Security Officer · Senior Agency Official for Privacy · System Security Officer · System Privacy Officer **TASK M-6 Ongoing Authorization** Review the security and privacy posture of the system on an ongoing basis to determine whether the risk remains acceptable. · Authorizing Official · Senior Accountable Official for Risk Management or Risk Executive (Function) · Chief Information Officer · Senior Agency Information Security Officer · Senior Agency Official for Privacy · Authorizing Official Designated Representative **TASK M-7 System Disposal** Implement a system disposal strategy and execute required actions when a system is removed from operation. · System Owner · Authorizing Official or Authorizing Official Designated Representative · Information Owner or Steward · System Security Officer · System Privacy Officer · Senior Accountable Official for Risk Management or Risk Executive (Function) · Senior Agency Information Security Officer · Senior Agency Official for Privacy

CIS Safeguard 5.6 · Centralize Account Management Centralize account management through a directory or identity service. Implementation Groups: 2,3 Asset Type: users Security Function: protect Parent Control: Account Management

CIS Safeguard 9.4 · Restrict Unnecessary or Unauthorized Browser and Email Client Extensions Restrict, either through uninstalling or disabling, any unauthorized or unnecessary browser or email client plugins, extensions, and add-on applications. Implementation Groups: 2,3 Asset Type: applications Security Function: protect Parent Control: Email and Web Browser Protections

Meeting the CMMC Level 2 self-assessment (§170.16) or CMMC Level 2 certification assessment (§170.17) requirements also satisfies the CMMC Level 1 self-assessment requirements detailed in §170.15 for the same CMMC Assessment Scope. b. Level 2 Comment: Commenters provided a number of very specific Level 2 assessment scenarios and asked for rule interpretation for each scenario.

Scenarios included differing scores for self-assessment and third-party assessment; assessment timing; conditional assessment expiration; and CUI enclaves. One commenter stated the language describing certificates of assessment lacked clarity and seems to allow an OSC to be issued a certificate of assessment but not be certified. Two comments stated that wording describing the expiration of a Conditional Level 2 self-assessment or certification could be interpreted to mean that the OSA/OSC would be permanently barred from seeking further contracts using information systems within that CMMC Assessment Scope. One comment said it was not clearly stated that a Level 2 third party assessment would satisfy contractual requirements for a Level 2 self-assessment. One comment stated that the rule does not clearly indicate whether a Level 2 assessment checks for more than just proper implementation of the 110 requirements in NIST SP 800-171 R2 and includes paragraphs (c) through (g) of DFARS clause 252.204-7012. This commenter advocated that those requirements be assessed only during DIBCAC assessments. Response: The rule has been updated to clarify that meeting the requirements for a CMMC Level 2 certification assessment satisfies a CMMC Level 2 self-assessment requirement for the same CMMC Assessment Scope. The term ‘certificate of assessment’ has been replaced with the term ‘Certificate of CMMC Status’ in the final rule. When an OSC has met all the requirements for a Level 2 certification assessment, a Certificate of CMMC Status is obtained from the C3PAO conducting the assessment. See § 170.9. Under CMMC, OSCs are not certified; rather, the assessed network receives a (printed page 83129) Certificate of CMMC Status for the CMMC Assessment Scope if the network meets all applicable certification requirements. No rule edit is necessary because § 170.19 is clear on this point. The phrase ‘until such time as a valid CMMC Level 2 self-assessment is achieved’ is added to the rule in the event a Conditional Level 2 self-assessment or Conditional Level 3 expires [see sections §§ 170.16(a)(1)(ii)(B)) and 170.17(a)(1)(ii)(B)]. The CMMC program does not assess paragraph (c) through (g) of DFARS clause 252.204-7012. The CMMC Program assesses the security requirements set forth in the FAR clause 52.204-21; National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 R2; and selected requirements from the NIST SP 800-172 Feb2021, as applicable (see table 1 to § 170.14(c)(4) CMMC Level 3 Requirements). If the contract requires a Level 2 self-assessment (i.e.,

| Access Control | Maintenance | Security Assessment and Monitoring |

|-----|-----|-----|

Awareness and Training | Media Protection | System and Communications Protection | | Audit and Accountability | Personnel Security | System and Information Integrity | | Configuration Management | Physical Protection | Planning | | Identification and Authentication | Risk Assessment | System and Services Acquisition | | Incident Response | | Supply Chain Risk Management | Below is an example of the Incident Response Testing requirement, which is part of the Incident Response (IR) family. The structure and content of a typical security requirement includes: ODPs support consistent security assessments in determining whether security requirements have been satisfied. If a federal agency or a consortium of agencies do not specify a particular value or range of values for an ODP, nonfederal organizations must assign the value or values to complete the security requirement.

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The national and economic security of the United States (U.S.) is dependent upon the reliable functioning of the nation's critical infrastructure. Positioning, Navigation, and Timing (PNT) services are widely deployed throughout this infrastructure. In a government-wide effort to mitigate the potential impacts of a PNT disruption or manipulation, Executive Order (EO) 13905, Strengthening National Resilience Through Responsible Use of Positioning, Navigation and Timing Services , was issued on February 12, 2020. The National Institute of Standards and Technology (NIST), as part of the Department of Commerce (DoC), produced this voluntary PNT Profile in response to Sec.4 Implementation (a), as detailed in the EO. The PNT Profile was created by using the NIST Cybersecurity Framework and can be used as part of a risk management program to help organizations manage risks to systems, networks, and assets that use PNT services. The PNT Profile is intended to be broadly applicable and can serve as a foundation for the development of sector-specific guidance. This PNT Profile provides a flexible framework for users of PNT to manage risks

when forming and using PNT signals and data, which are susceptible to disruptions and manipulations that can be natural, manufactured, intentional, or unintentional.

The Defense Industrial Base (DIB) is the worldwide industrial complex that enables research and development, design, production, delivery, and maintenance of military weapons systems, subsystems, and components or parts to meet U.S. military requirements. The DIB includes over 300,000 companies and their subcontractors that perform work on DoD contracts. These organizations must comply with cybersecurity requirements (DFARS, CMMC) to protect Controlled Unclassified Information and Federal Contract Information.

(2) The term "information technology" includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources. (3) The term "information technology" does not include any equipment acquired by a contractor incidental to a contract. * * * * PART 208-REQUIRED SOURCES OF SUPPLIES AND SERVICES 3. Revise section 208.405 to read as follows: 208.405 Ordering procedures for Federal Supply Schedules. Include an evaluation factor regarding supply chain risk (see subpart 239.73) when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as defined in 239.7301. 4. In section 208.7402, revise paragraph (2) to read as follows: 208.7402 General. * * * * (2) Include an evaluation factor regarding supply chain risk (see subpart 239.73) when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as defined in 239.7301. PART 212-ACQUISITION OF COMMERCIAL ITEMS 5. Amend section 212.301 by: a. Adding paragraph (c); and b. Revising paragraphs (f)(xv)(C) and (D). The addition and revisions read as follows: 212.301 Solicitation provisions and contract clauses for acquisition of commercial items. (c) Include an evaluation factor regarding supply chain risk (see subpart 239.73) when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as defined in 239.7301. (f) * * * (xv) * * * (C) Use the provision at 252.239-7017, Notice of Supply Chain Risk, as prescribed in 239.7306(a), to comply with section 806 of Public Law 111-383 . (D) Use the clause at 252.239-7018, Supply Chain Risk, as prescribed in 239.7306(b), to comply with section 806 of Public Law 111-383 . * * * * PART 213-SIMPLIFIED ACQUISITION PROCEDURES 6. Add section 213.106-1 to read as follows: 213.106-1 Soliciting competition. (a)(2) Include an evaluation factor regarding supply chain risk (see subpart 239.73) when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as defined in 239.7301. PART 214-SEALED BIDDING 7. Add section 214.201-5 to read as follows: 214.201-5 Part IV-Representations and instructions. (c) Include an evaluation factor regarding supply chain risk (see subpart 239.73) when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, as defined in 239.7301. 8. Add subpart 214.5 to read as follows: Subpart 214.5 Two-Step Sealed Bidding

(E) For compatibility with the exemption claimed from subsection (f), the civil remedies provisions of subsection (g) must be suspended for this record system. Because of the nature of criminal investigations, standards of accuracy, relevance, timeliness and completeness cannot apply to this record system. Information gathered in criminal investigations is often fragmentary and leads relating to an individual in the context of one investigation may instead pertain to a second investigation. (F) From subsection (e)(1) because the nature of the criminal investigative function creates unique problems in prescribing a specific parameter in a particular case with respect to what information is relevant or necessary. Also, due to USSOUTHCOM's close liaison and working relationships with the other Federal, as well as state, local and foreign country law enforcement agencies, information may be received which may relate to a case under the investigative jurisdiction of another agency. The maintenance of this information may be necessary to provide leads for appropriate law enforcement purposes and to establish patterns of activity which may relate to the jurisdiction of other cooperating agencies. (G) From subsection (e)(2) because collecting information to the greatest extent possible directly from the subject individual may or may not be practicable in a criminal investigation. The individual may choose not to provide information and the law enforcement process will rely upon significant information about the subject

from witnesses and informants. (H) From subsection (e)(3) because supplying an individual with a form containing a Privacy Act Statement would tend to inhibit cooperation by many individuals involved in a criminal investigation. The effect would be somewhat inimical to established investigative methods and techniques. (I) From subsection (e)(5) because the requirement that records be maintained with attention to accuracy, relevance, timeliness, and completeness would unfairly hamper the criminal investigative process. It is the nature of criminal law enforcement for investigations to uncover the commission of illegal acts at diverse stages. It is frequently impossible to determine initially what information is accurate, relevant, timely, and least of all complete. With the passage of time, seemingly irrelevant or untimely information may acquire new significance as further investigation brings new details to light. (J) From subsection (e)(8) because the notice requirements of this provision could present a serious impediment to criminal law enforcement by revealing investigative techniques, procedures, and existence of confidential investigations. (3)-(15) [Reserved] (16) System identifier and name. DWHS E06, Enterprise Correspondence Control System (ECCS). (i) Exemption.

| Evaluation of a Computer Security Management Aid: A Risk Management Tool | VII-8 | | LIST OF TABLES | LIST OF TABLES | | | TABLE 1-1 - Computer Security Areas and SOWs | TABLE 1-1 - Computer Security Areas and SOWs | 1-3 | | TABLE 1-2 - Major Federal Directives, Computer Security Requirements, and Document Sections | TABLE 1-2 - Major Federal Directives, Computer Security Requirements, and Document Sections | 1-4 | | LIST OF APPENDICES | LIST OF APPENDICES | | | APPENDIX A: ANNOTATED REFERENCES | APPENDIX A: ANNOTATED REFERENCES | A-1 | | APPENDIX B: SAMPLE TEXT FOR REPORTING REQUIREMENTS, TECHNICAL CONTACTS, AND OTHER A SOW | IN | B-1 | | APPENDIX C: ALTERNATE TEXT FOR REPORTING REQUIREMENTS, TECHNICAL CONTACTS, AND OTHER IN A SOW | APPENDIX C: ALTERNATE TEXT FOR REPORTING REQUIREMENTS, TECHNICAL CONTACTS, AND OTHER IN A SOW | C-1 | | APPENDIX D: SAMPLE JOB DESCRIPTIONS | APPENDIX D: SAMPLE JOB DESCRIPTIONS | D-1 | | APPENDIX E: COMPUTER SECURITY AREA AND SOW-SPECIFIC REFERENCES | APPENDIX E: COMPUTER SECURITY AREA AND SOW-SPECIFIC REFERENCES | E-1 | | APPENDIX F: SAMPLE WORK PLAN DEVELOPMENT TASK STATEMENTS | APPENDIX F: SAMPLE WORK

Numerous commenters asked whether CMMC could leverage the results of other assessments, such as ISO/IEC 27001/27002, NIST SP 800-53, NIST SP 800-172, HITRUST, DoE Cybersecurity Capability Maturity Model, NIAP Common Criteria Testing Laboratory Services (CCEVS), Committee on National Security Systems (CNSS) Instruction No. 12533 (CNSSI 12533), ISA/IEC-62443, DoD's Security Technical Implementation Guides (STIG), NIST Cyber Security Framework (CSF), NIST Risk Management Framework (RMF), the American Institute of CPAs Service and Organizational Controls, Service and Organization Controls (SOC) Trust Services Criteria (SOC 2), ISA/IEC-62443, ITAR, Criminal Justice Information Services (CJIS) security standards, and non-ISO/IEC standards used by foreign partners such as the Australian Cybersecurity Centre Essential Eight Maturity Model. Response: The CMMC Program standards acceptance is defined in § 170.20 of this rule. 11. CMMC Assessment Scope Comment: Multiple commenters requested details on assessment boundaries and what systems are in-scope for a CMMC assessment. Questions included how assessment boundaries are defined, how networks composed of federal components (including systems operated on behalf of the government) and non-federal components are addressed, how centralized security services are treated, and how enduring exceptions are handled. Response: § 170.19 states that prior to a CMMC assessment, the OSA must define the CMMC Assessment Scope for the assessment, representing the boundary with which the CMMC assessment will be associated. This section includes detailed guidance on how to define the CMMC Assessment Scope, how different categories of equipment are defined to be in- or out-of-scope for an assessment, how the security of specialized equipment is expected to be managed, External Service Providers considerations, and the incorporation of people, technology, and facilities into the boundary. GFE, IoT, OT, and, as defined, Restricted Information Systems and Test Equipment are categorized as Specialized Assets in § 170.19. NIST SP 800-171 Rev 2 uses the term enduring exceptions to describe how to handle exceptions for Specialized Assets. 12. Applicability of Multiple CMMC Levels Comment: Two commenters sought confirmation that it is acceptable for contractors with multiple business segments to have one or more CMMC assessments (e.g., one segment at Level 1, another at Level 2). Commenters also wanted to know if systems within the scope of an assessment require multiple assessments if the systems are used to support tasks under multiple contracts. Another asked, if a company has multiple Commercial and Government Entity (CAGE) codes, whether a single assessment can cover all CAGE codes. Response:

performance metrics, availability, status monitoring, usability, and cost effectiveness)? How effective would a federal government-sponsored grand challenge program be at drawing attention to

and promoting work on specific technical problems? 8. An Incentives Framework for Evolving Cyber-Risk Options and Cybersecurity Best Practices Outside the CIKR sectors, U.S. businesses and consumers generally have resorted to their own devices and evolved their own practices for dealing (or not dealing) with cyber risks. In other words, across large segments of the economy, the level of cybersecurity relies upon the private sector's development, dissemination and adoption of best practices. As Internet usage has grown domestically and abroad, U.S. companies have been faced with a range of Internet-related issues. Based on feedback the Task Force received, the adoption of industry best practices is uneven. According to some stakeholders, smaller and medium sized businesses may lack the specialized knowledge and resources necessary to meet cybersecurity challenges. Some stakeholders also suggested that the fundamental challenge may be a misalignment of incentives. Still others argued for greater leadership from industry and/or government in developing improved standards for securing cyberspace in a manner that will promote greater economic benefits from an expanding Internet economy. These assertions suggest several questions: Are existing incentives adequate to address the current risk environment? Do particular business segments lack sufficient incentives to make cybersecurity investments? If so, why? What would be the best way to encourage businesses to make appropriate investments in cybersecurity? Are there public policies or private sector initiatives in the United States or other countries that have successfully increased incentives to make such security investments? Are there disincentives that inhibit cybersecurity investments by firms? If so, what should be done to eliminate them? Are there examples of cybersecurity best practices that have been (or can be) sufficiently tailored to meet the diverse needs of commercial actors outside the CIKR sectors? Are those best practices well known and understood? Should a set, or sets, of best practices be developed to guide commercial organizations' investment decisions? What role, if any, should the U.S. Government play in their development?

o. Whether the proposed requirement in the standard for evaluation, to perform a written technical and nontechnical evaluation within a reasonable period of time before making a change in the regulated entity's environment or operations pursuant to the requirements, is sufficiently clear. If not, how should the Department clarify it? For example, should the Department require a specific amount of time, and if so, what length of time? p. Whether at least once every 12 months is the appropriate frequency for reviewing and updating written policies and procedures for patch management, sanctions policies and procedures information system activity review, workforce security, and information access management. q. Whether as reasonable and appropriate in response to changes in the risk analysis, but at least once every 12 months, is the appropriate frequency for reviews of a regulated entity's written risk management plan. r. Whether the proposed frequency for security awareness training is appropriate. s. Whether the proposed substance of the security awareness training is appropriate, and any recommendations for additional required content. t. Whether the proposed timelines for applying patches, updates, and upgrades are appropriate. u. Whether the Department should set a time limit for applying patches, updates, and upgrades to configurations of relevant electronic information systems to address moderate and low risks. If so, please explain and provide a recommendation. v. Whether the amount of time regulated entities currently retain records of information system activity varies by the type of record, and for how long such records are retained. w. Whether the Department should specify the length of time for which records of information system activity should be retained. If so, please explain. x. Whether the Department should require that a regulated entity notify other regulated entities of the termination of a workforce member's access to ePHI in less than 24 hours after the workforce member's termination. If so, please explain what would be an appropriate period of time (e.g., three business hours, 12 hours). y. Whether at least once every 12 months is the appropriate frequency for testing security incident response plans, documenting the results, and revising such plans. z. Whether it is reasonable and appropriate to require that regulated entities restore loss of critical relevant electronic information systems and data in 72 hours or less. aa. Whether the Department should require a regulated entity to restore all of its relevant electronic information systems and data within 72 hours? bb. Whether the Department should require some regulated entities to restore their relevant electronic information systems and data in less than 72 hours? If so, please explain. cc. Whether at least once every 12 months is the appropriate frequency for the testing of contingency plans?

Approaches and Challenges of Federal Cybersecurity Awareness Programs ## Approaches and Challenges of Federal Cybersecurity Awareness Programs Organizational security awareness programs experience a number of challenges, including lack of resources, difficulty measuring the impact of the program, and perceptions among the workforce that training is a boring, 'check-the-box'

activity. While prior surveys and research have examined programs in the private sector, there is little understanding of whether these findings also apply within the U.S. government. To address this gap and better understand the needs, challenges, practices, and necessary competencies of federal security awareness teams and programs, NIST conducted a research study that leveraged both qualitative and quantitative methodologies. This companion document to NISTIR 8420 'Federal Cybersecurity Awareness Programs: A Mixed Methods Research Study' reports on a subset of study results focused on identifying the current approaches and challenges of security awareness programs within the federal government. Insights gained from these results are informing guidance and other initiatives to aid federal organizations in building effective security awareness programs. While focused on the U.S. government, findings may also have implications for organizational security awareness programs in other sectors.

Control EC-1: nt for Reference Application Infrastructure Connectivity (between network elements) and access policies (between service instances) are network-tier policies and identity-tier policies, respectively. Consider the following example set of policies that contain a combination of network-tier and identity-tier policies. Network-tier policies can be further categorized into coarse-grained and fine-grained policies.

- Coarse-grained network-tier policies - These perimeter control policies are informally called firewall rules and are mostly static as they specify:
 - o The network location of the egress gateway from which the network edge element at the exit point of a cloud network (e.g., outbound firewall, such as the one at the edge of a cloud) can receive traffic
 - o The network location of the ingress gateway to which the incoming traffic that lands at the entry point of the on-premises network edge (e.g., inbound firewall at the entry point to an on-premises network) should be routed:
- Fine-grained network-tier policies - This category of policies is also called microsegmentation policies, and they specify the pathways for traffic flowing into and out of the services located within the network subnets at the cloud location or onpremises location.
 - o Specify the path on which the outbound traffic from a service or an application (e.g., App 1 in Fig. 2) can flow. The elements in the path that are specified include the egress gateway at the edge of the cluster and, subsequently, the outbound firewall for the network (cloud network in this example).
 - o Specify the path for the inbound traffic into the on-premises network to reach the target application. The elements in the path start from the inbound firewall at the edge of the on-premises network to the ingress gateway in an on-premises cluster to the network subnet where the target service is located.
 - o Notably, they specify how traffic can flow 'east-west' (i.e., inside of the perimeter).

DFARS 252.204-7012 (Safeguarding Covered Defense Information and Cyber Incident Reporting) Core CUI protection clause requiring NIST SP 800-171 implementation, cyber incident reporting within 72 hours, and preservation of evidence. Under DFARS 252.204-7012, contractors must report cyber incidents to the DoD Cyber Crime Center (DC3) within 72 hours of discovery. The report must include the nature of the incident, affected systems, compromised CUI, and preservation of forensic evidence for at least 90 days. Contractors must also submit malicious software to DC3 and provide access to affected systems if requested.

Section 164.304 includes definitions for key regulatory terms in the Security Rule. The Department proposes to add ten new defined terms and to modify the definitions of fifteen existing terms. The proposed new regulatory terms would be: Deploy, Implement, Electronic information system, Multi-factor authentication, Relevant electronic information system, Risk, Technical controls, Technology asset, Threat, and Vulnerability. The definitions we propose to modify are for the following terms: Access, Administrative safeguards, Authentication, Availability, Confidentiality, Information system, Malicious software, Password, Physical safeguards, Security or Security measures, Security incident, Technical safeguards, User, and Workstation. Generally, the Department is proposing to add or modify regulatory terms that would either clarify how regulated entities should apply the standards and implementation specifications or modernize the rule to better account for changes in the environment in which health care is provided.

1. Clarifying the Definition of 'Access' a.

Current Provision and Issues To Address The Security Rule defines the term 'access' as the ability or means necessary to perform a set of activities describing how a user may interact with a system resource. [346] These activities are reading, writing, modifying, communicating data/information, or otherwise using any component of an information system. The definition applies only to the Security Rule, not to the Breach Notification Rule or the Privacy Rule. The term 'access' defines the scope of some key regulatory provisions in the Security Rule. For example, whether a person meets the definition of a 'user' is determined based on whether their access to

information or a component of the regulated entity's information system is authorized. [347] The definition (printed page 923) of the term "security incident" requires consideration of whether a person attempted to access or accessed information without authorization. [348] To determine whether a regulated entity complied with the administrative safeguard standard for workforce security, the Department must consider to what extent a regulated entity established policies and procedures for ensuring that workforce members have appropriate access to ePHI. [349] The current definition is expansive but not fully representative of how users could interact with information today. As discussed above, users create, receive, maintain, and transmit information in more ways now than they did ten years ago. Thus, the Department believes that it is critical for the Department to consider modifying the definition of this term to adequately reflect the current electronic environment. b. Proposal

The revisions and additions read as follows: § 159.6 Procedures. (a) Standing Combatant Command (CCMD) guidance and procedures. Each CDR with a geographic AOR shall develop and publish guidance and procedures for PSCs and PSC personnel operating during contingency operations, humanitarian or peace operations, or other military operations or exercises within their AOR, consistent with applicable law; this part; applicable Military Department publications; and other applicable DoD issuances including DoD Directive 3020.49, DoD Instruction 1100.22, "Policy and Procedures for Determining Workforce Mix," FAR, DFARS, DoD Instruction 3020.41, DoD Directive 2311.01E, "DoD Law of War Program" (available at <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodd/231101p.pdf?ver=2020-07-02-143157-007>); DoD 5200.08-R, "Physical Security Program" (available at <https://www.esd.whs.mil/Portals/54/Documents/DD/issuances/dodm/520008rm.pdf>); CJCS Instruction 3121.01B,, and DoD Directive 5210.56. The guidance and procedures shall: * * * * * (2) * * * (ii) Assessing compliance with DoD approved business and operational standards for private security functions. * * * * * (v) Requirements for the PSC to cooperate with any investigation conducted by the DoD, including by providing access to its employees and relevant information in its possession regarding the matter(s) under investigation. * * * * * (b) Subordinate guidance and procedures. * * * (c) Consultation and coordination. * * * Dated: August 29, 2022. Aaron T. Siegel, Alternate OSD Federal Register Liaison Officer, Department of Defense. Footnotes 1. "CJCS Instruction 3121.01B provides guidance on the standing rules of engagement (SROE) and establishes standing rules for the use of force for DoD operations worldwide. This document is classified secret. CJCS Instruction 3121.01B is available via Secure internet Protocol Router Network at <https://jsportal.osd.smil.mil> . Back to Citation [FR Doc. 2022-18992 Filed 9-8-22; 8:45 am] BILLING CODE 5001-06-P

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 202, 204, 212, 232, and 252 [Docket DARS-2019-0019] RIN 0750-AK37 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (printed page 19682) (DFARS) to implement a section of the National Defense Authorization Act for Fiscal Year 2017 that amends 10 U.S.C. 2307 to address the use of performance-based payments. DATES: Effective April 8, 2020. FOR FURTHER INFORMATION CONTACT: Ms. Amy Williams, DPC/DARS, at 571-372-6106. SUPPLEMENTARY INFORMATION: I. Background DoD published a proposed rule in the Federal Register at 84 FR 18221 on April 30, 2019, to implement section 831 of the National Defense Authorization Act (NDAA) for Fiscal Year (FY) 2017, which amends 10 U.S.C. 2307 to address the use of performance-based payments (PBPs). Eleven respondents submitted public comments in response to the proposed rule. II. Discussion and Analysis DoD reviewed the public comments in the development of the final rule. There was widespread support for the proposed implementation of 10 U.S.C. 2307(b)(2) requirement that PBPs shall not be conditioned upon costs incurred in contract performance, but on achievement of performance outcomes (232.1001(a)). A number of changes are made in the final rule, which are expected to increase support for the rule, such as permitting alternate forms of security for performance-based payments and clarifying that an acceptable accounting system is not required for incurred costs under the performance-based payments clause. A discussion of the comments and the changes made to the rule as a result of the comments received is provided, as follows: A. Summary of Significant Changes From the Proposed Rule 1. The requirement for

compliance with Generally Accepted Accounting Principles (GAAP) in order to receive performance-based payments at DFARS 232.1003-70 and in the representation at 252.232-7015 has been modified to apply to the contractor's financial statements, rather than the ·output· of the contractor's accounting system, and the requirement that compliance with GAAP must be evidenced by audited financial statements has been removed.

While some cyber intrusions are highly sophisticated, some require relatively little skill or effort. For instance, criminals can use widely available, low cost ·crimeware kits· to exploit computer systems and software vulnerabilities in order to launch malware against targeted computer systems. [15] The financial cost of cyber threats to firms and their customers appears to be significant. Though current fraud losses attributed to cybersecurity data breaches are small in comparison to total annual business fraud losses, they are increasing, rising from 7 percent of total fraud losses in 2007 to 11 percent in 2008. In 2009, the dollar loss from all cases of online crime referred to law enforcement in the United States reached \$550 million, more than twice the 2008 level. [16] Small businesses have just as much reason to focus on cybersecurity as do larger enterprises yet they are less likely to have adequately protected themselves from their risks. According to a National Cybersecurity Alliance poll, 65 percent of small businesses store customer data online, 43 percent store financial records online, 33 percent store credit card information online, and 22 percent have intellectual property and other sensitive corporate content online. [17] The same poll shows that only 14 percent of these firms have anyone solely focused on information technology security; only 53 percent check their computers to ensure that anti-virus, anti-spyware, firewalls, and operating systems are up to date; 20 percent say that they use the minimum threshold of security to protect customer and employee data, but 42 percent believe that their customers are (printed page 44219) concerned about the IT security of their business. Though many businesses are increasing their cybersecurity budgets, anecdotally, the Task Force has been told that there is a continuous requirement for IT managers to justify their expenditure of company resources on cybersecurity. Given this state of affairs, the Task Force believes that public policies affecting cybersecurity on the Internet, as well as private sector norms (both good and bad), require a fresh look. The Task Force recognizes the valuable roles, responsibilities, and capabilities of the private sector in creating tools and strategies to mitigate cyber risks associated with the Internet. More broadly, over the past two decades, the nation has benefitted greatly from industry-led, Internet-driven innovation and growth, with those benefits reflected throughout the entire economy. That said, the persistence of the cybersecurity challenges compels the Department to seek a better understanding of both how those challenges are affecting U.S. businesses and citizens, as well as useful steps that can enhance the security of e-commerce. Small, medium, and large businesses, and consumers, will continue to increase their reliance on the Internet. As that reliance grows, the level of cybersecurity must increase as well.

CIS Safeguard 13.2 · Deploy a Host-Based Intrusion Detection Solution Deploy a host-based intrusion detection solution on enterprise assets, where appropriate and/or supported. Implementation Groups: 2,3 Asset Type: devices Security Function: detect Parent Control: Network Monitoring and Defense

(b) No system of records within the NRO shall be considered exempt under subsection (j) or (k) of the Privacy Act until the exemption and the exemption rule for the system of records has been published as a final rule in the Federal Register . (c) An individual is not entitled to have access to any information compiled in reasonable anticipation of a civil action or proceeding (5 U.S.C. 552a(d)(5)). (d) Proposals to exempt a system of records will be forwarded to the Defense Privacy Office, consistent with the requirements of this part, for review and action. (1) System identifier and name. QNRO-23, Counterintelligence Issue Files. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) and/or (k)(5) from the following

subsections of 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (H) and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5). (iii) Reasons. (A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the identity of the recipient, could alert the subject to the existence of the investigation or prosecutable interest by NRO or other agencies. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence. (B) From subsections (d)(1) through (d)(4), and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant (printed page 14787)

3.1.4 Cyber Resiliency Conflicts and Synergies ... 3.1.4 Cyber Resiliency Conflicts and Synergies
Cyber resiliency techniques can interact in several ways. 3.1.4 and identified in Appendix D, Table D-3).

<http://www.whitehouse.gov/news/releases/2003/12/20031217-5.html>. Back to Citation 3.
Copies of U.S. Department of Justice (DOJ) Guide can be viewed at <http://www.usdoj.gov/oip/>.
Back to Citation [FR Doc. E7-24359 Filed 12-18-07; 8:45 am] BILLING CODE 5001-06-P

- Facilitating communication across the organizational risk management levels; - Encouraging the organization-wide identification of common controls and the development of organizationally tailored control baselines; - Reducing the complexity of the IT infrastructure; and - Providing additional methods to identify, prioritize, and focus resources on highvalue assets commensurate with risk. - Publication of Draft NISTIR 8259, Core Cybersecurity Feature Baseline for Securable IoT Devices: A Starting Point for IoT Device Manufacturers [29]. This NISTIR defines a baseline of cybersecurity features that manufacturers may voluntarily adopt for the IoT devices that they produce. It also provides information on how manufacturers can identify and implement features beyond the baseline that are most appropriate for their customers. - Publication of Draft NISTIR 8267, Security Review of Consumer Home Internet of Things (IoT) Products, which presents the results of technical assessments on the security features of various 'smart' products (e.g., smart light bulbs, security cameras, and doorbells) [30]. The report provides recommendations, information on the observations of the devices' security features, current practices, and the means by which these current practices could be improved. These technical assessments will help the NCCoE better address consumer home IoT security in a holistic manner in future projects. How does a system administrator know if some of the hardware or software in their systems contain vulnerabilities? Chances are that they utilize information that is freely available from the NVD. The NVD is a comprehensive cybersecurity vulnerability database that tracks vulnerability discovery trends over time, enabling users to assess changes in vulnerability discovery rates within specific products or types of vulnerabilities.

The DoD declines to comment on the reposting of information being reported in the media. This rule identifies requirements for the CAICO role in the ecosystem. The DoD has a variety of options available to address issues with reliance on a single CAICO. These include but are not limited to working with the CMMC AB to identify a new/replacement CAICO. The final rule includes a requirement for the Accreditation Body, CAICO, and C3PAOs to adhere to appropriate ISO/IEC standards, which include the current version of the standard for conformity assessment (ISO/IEC 17024:2012(E) located at ISO website: www.iso.org/standard/52993.html). All CMMC ecosystem members are required inter alia to abide by the appropriate ethics and conflicts of interest policies established by the CMMC AB and CAICO. Rule content pertaining to ethics, quality assurance functions, record keeping, data encryption, security, etc. functions across the ecosystem are tailored to reflect the role each entity fills in the ecosystem. Repeating this content in the section of each ecosystem role serves to emphasize the importance of adherence to these requirements. DoD disagrees with the commenter's suggestion that certain CAICO requirements are not needed or are redundant. The DoD requirement for documentation in English refers to official information provided to the Accreditation Body or the DoD. The commenter's preferred rewording of § 170.10(b)(3) is unnecessary because there is a

separate requirement for the CAICO to meet ISO/IEC standards, and this rule does not codify non-DoD requirements. The DoD declines to remove the requirement in § 170.10(b)(10) to provide status information to the CMMC AB because it is necessary for program management. The rule retains the separation of duties requirement at § 170.10(b)(11), which is more specific than the management of impartiality required under ISO/IEC 17024:2012(E). The DoD declines to delete certification requirements for CCI. Having the technical background as a CCP or CCA does not ensure all the instructor-unique qualifications necessary to be a CCI are met. The DoD also declines to remove the reference to § 170.10 from § 170.12(b)(1) since it is accurate that the CAICO certifies CCIs. Section § 170.10(b)(13) ensures that personal information is encrypted and protected in all CAICO information systems and databases and those of any CAICO training support service providers. DoD disagrees with the commentor's statement that training support service providers of the CAICO be allowed to disclose information about CCAs and/or CCPs. § 170.10 references the CAICO requirements. Entities providing training support services to the CAICO are not a part of the assessment process in the ecosystem. It is not up to them to release data on certified persons in the ecosystem. Any metrics regarding certifications will come from the CAICO.

Two comments asserted that the description of affirmations requirement could be mis-interpreted as suggesting that primes and subcontractors all submit a single affirmation or that one contractor must affirm another's continuing compliance. One comment requested clarification about FedRAMP requirements for Cloud Service Providers. Some comments asked whether POA&Ms must be documented in the System Security Plan. One comment recommended punctuation and grammatical edits and asked for clarification of rule text that discusses the impact of not logically or physically separating contractor-owned information systems that process, store, or transmit FCI (or CUI) from those that do not. Response: This rule follows the format and includes all sections required in OMB guidelines for formal rulemaking. The DoD lacks authority to modify the template or omit required sections, as requested by some commenters. In addition, one commenter recommended that the supplemental Assessment Guides be consolidated with and cross referenced to requirements for the CMMC Levels in the same document. The DoD interpreted this recommendation as a request to integrate all information in the supplemental guidance into the rule text, which does not align with rulemaking guidelines (1 CFR part 51). No changes were made to consolidate or integrate the supplemental guidance documents, which are not codified and are provided as optional resources to assist OSAs. The regulatory content in the 32 CFR part 170 CMMC Program rule takes precedence. Some commenters criticized the preamble summary paragraph, and one submitted a preferred rewrite that oversimplified the content so far as to alter the intended meaning. For that reason, the specific revisions were not incorporated. However, the DoD has revised the final rule to begin with a simplified statement of its purpose, as follows: 'With this final rule, DoD establishes a scalable way to verify, through assessment, that contractors have implemented required security measures necessary to safeguard DoD's Federal Contract Information (FCI) and Controlled Unclassified Information (CUI)'. The DoD strove to streamline the writing style. Note that the preamble is not part of the regulatory text, however, it is a required part of the rulemaking template. The DoD made the following changes to the preamble based on requests for text modifications. The preamble is updated to change the verb 'will' to 'should', where appropriate. The preamble and regulatory text have been updated to clarify that a Plan of Action need not be part of the System Security Plan. The sentence in the preamble overview about FAR clause 52.204-21 requirements has been rewritten to describe them as 'the minimum necessary' to receive FCI, rather than describing them as 'elementary' for 'basic' cybersecurity. Note that the title of the FAR clause 52.204-21 clause is Basic Safeguarding Requirements.

The contractor will limit disclosure of classified information to that specific information authorized in connection with an approved visit request and an export authorization, as required.

(D) Temporary exports. Classified articles, including articles that require the use of classified information for operation, exported for demonstration purposes must remain under U.S. control. The contractor must obtain an export authorization from the relevant authority (i.e., from the Department of State in accordance with 22 CFR parts 120-130 , also known as and referred to in this rule as the 'International Traffic in Arms Regulations,' or from the Department of Commerce in accordance with 15 CFR parts 730-774 , also known as the 'Export Administration Regulations').

(4) Direct commercial arrangements. (i) The disclosure of classified information may be authorized pursuant to a direct commercial sale with the appropriate export authorization. A direct commercial arrangement includes sales, loans, leases, or grants of classified items, including sales under a government agency sales financing program. (ii) If a proposed disclosure is in support of a foreign

government requirement, the contractor should consult with U.S. in-country officials, normally the U.S. Security Assistance/Armaments Cooperation Office or Commercial Counselor. (A) Before a contractor makes a proposal to a foreign interest that involves the eventual disclosure of U.S. classified information, the contractor must obtain appropriate government disclosure authorization. (B) Such disclosure authorization does not equate with authorization for export. Export authorization must be obtained from the appropriate regulatory body. (iii) The contractor will request a FCL assurance for a foreign entity through the CSA from the security authority of the foreign entity's sponsoring government prior to entering into a contractual arrangement with the foreign entity. (5) Subcontract security provisions. (i) A U.S. contractor may be authorized to enter into an agreement involving classified information with a foreign contractor. The U.S. contractor's empowered official will verify the contractor can release the information to a foreign person. Such agreements may include: (A) Award of a subcontract. (B) Department of State authorized manufacturing license agreement, technical assistance agreement, or other direct commercial arrangement. (ii) The contractor will incorporate security provisions into the subcontract document or agreement, and provide security classification guidance by means of a Contract Security Classification Specification, or equivalent. (iii) The contractor will provide a copy of the signed contract with the provisions and the classification guidance to the CSA.

Twenty-three comments expressed concern with or requested clarification regarding CUI marking. Twelve comments specifically noted concern with CUI markings being applied to too many documents, in part because CUI was an ambiguous concept. They requested the DoD encourage personnel to mark documents as CUI only when appropriate and provide better guidance for managing flow-down clauses. Another comment noted that many small businesses are currently subject to NIST SP 800-171 requirements through DFARS contract clause flow-down and cannot say with certainty that they have CUI in their possession. The comment further noted that small businesses regularly receive mismarked data. One comment stated there is an increased use of automatic CUI marking on DoD communications, seemingly without regard to content. One comment stated that the rule fails to outline a mechanism for reporting government mishandling, and that contractors should use a reporting system to minimize their own risk and liability. One comment requested the rule be edited to prevent Program Managers or requesting activities from assigning a CMMC Level 3 requirement unless they have high confidence that 80+ percent of CUI and/or FCI under the relevant contract has complete CUI markings. Another comment stated that the Federal government should develop a marking schema to communicate information safeguarding requirements, while yet another stated that DoD must publish a training module for contracting officers so that they are properly classifying documents prior to finalization of this rule. One comment stated CUI across the DoD is diverse and what may be CUI for one system may not be for another. The comment then questioned how this proposed rule and SPRS would accommodate these facts without assuming and mandating that all defense contractor information systems meet the same architecture, security, and cybersecurity standards. Response: The CMMC Program will not provide CUI guidance materials to industry as it is outside the scope of this CMMC rule. Relevant information regarding what to do when there are questions regarding appropriate marking of CUI may be found at 32 CFR 2002.50 - Challenges to designation of information as CUI. The DoD declined to incorporate suggested edits to the CMMC Level 3 requirements regarding confidence in proper CUI and/or FCI markings. The DoD's role as data owner is documented in the CUI Program implementing policies and the requirements of 32 CFR part 2002. DoDI 5200.48, states: The authorized holder of a document or material is responsible for determining, at the time of creation, whether information in a document or material falls into a CUI category. If so, the authorized holder is responsible for applying CUI markings and dissemination instructions accordingly. DoD Manual 5200.01 outlines DoD's Information Security Program and includes Volume 2, Marking of Information. The DoD declines to incorporate by reference those (printed page 83105)

The statute also directed the Secretary to adopt initial security standards within 18 months of its (printed page 903) enactment. [43] In adopting security standards for health information, HIPAA requires the Secretary to consider all of the following: [44] The technical capabilities of record systems used to maintain health information. The costs of security measures. Training for persons who have access to health information. The value of audit trails in computerized record systems. The needs and capabilities of small health care providers and rural health care providers. [45] Congress contemplated that the Department's rulemaking authorities under HIPAA would not be static. In fact, Congress specifically built in a mechanism to adapt such regulations as technology and health care evolve, directing the Secretary to review and adopt modifications to the Administrative Simplification standards, including the security standards, as determined

appropriate, but not more frequently than once every 12 months. [46] That statutory directive complements the Secretary's general rulemaking authority to make and publish such rules and regulations as may be necessary to the efficient administration of the functions with which the Secretary is charged. [47] The Secretary may adopt either a standard developed, adopted, or modified by a standard setting organization that relates to a standard that the Secretary is authorized or required to adopt under the Administrative Simplification provisions, or a standard that is different if the different standard will substantially reduce administrative costs to health care providers and health plans. [48] If no standard has been adopted by any standard setting organization, the Secretary shall rely on the recommendations of the National Committee on Vital and Health Statistics (NCVHS) and consult with Federal and State agencies and private organizations. [49] 2. Health Information Technology for Economic and Clinical Health (HITECH) Act On February 17, 2009, Congress enacted the Health Information Technology for Economic and Clinical Health Act of 2009 (HITECH Act), part of the American Recovery and Reinvestment Act of 2009 (ARRA), [50] promoting the nationwide adoption and standardization of health information technology (health IT) to support the electronic sharing of clinical data. The HITECH Act created financial incentives for health IT use among health care practitioners by providing funding for investing in health IT infrastructure, purchasing certified electronic health records (EHRs), and training on and the dissemination of best practices to integrate health IT. [51] The Purpose statement of an accompanying House of Representatives report [52] on the Energy and Commerce Recovery and Reinvestment Act [53]

CMMC Program rule has been updated to add -in performance of the DoD contract- to §.170.3, and the 48 CFR part 204 CMMC Acquisition rule will provide the contractual direction. A common carrier's information system is not within the contractor's CMMC Assessment Scope if CUI is properly encrypted during transport across the common carrier's information system. A common carrier who is a DoD contractor or subcontractor is responsible for complying with the CMMC requirements in their contracts. CUI encryption requirements already apply to the OSA, not the telecommunications network provider. The lack of adequate encryption on the part of the OSA would not trigger application of CMMC requirements to the common carrier's network. The term -common carrier- appears in the comment section to a previous rule making process. Its definition and use are taken from CNSSI 4009. Efforts to define it or related terms by other agencies are outside the scope of the CMMC Program. Commenter scenarios where a common carrier would be privy to an OSA's encryption keys are unrealistic. DoD declines to provide additional guidance. CMMC Program requirements make no change to existing policies for information security requirements implemented by DoD. Policies for CUI and creation of program documentation, to include Security Classification Guides, are separate from this rule. Relevant policies include DoDI 5200.48 -Controlled Unclassified Information- and DoD Manual 5200.45 -Instructions for Developing Security Classification Guides-. CMMC Program requirements will be identified as solicitation requirements. Contractors will be required to meet the stated CMMC requirements, when applicable, at or above the level identified. For this reason, it is up to each DIB organization to determine which CMMC level they should attain. Questions regarding specific contractual matters are outside of the scope of this rule and may be addressed by the 48 CFR part 204 CMMC Acquisition rule. The CMMC program will be implemented as a pre-award requirement. c. Joint Ventures Comment: Two commenters requested clarification as to whether CMMC requirements will apply to companies engaged in Joint Ventures. Response: CMMC program requirements are applicable when DoD requires processing, storing, or transmitting of either FCI or CUI in the performance of a contract between DoD and the respective contractor. CMMC Program requirements will apply to information systems associated with contract efforts that process, store, or transmit FCI or CUI, and to any information system that provides security protections for such systems, or information systems not logically or physically isolated from all such systems. The identity of an offeror or contractor as a joint venture does not in and of itself define the scope of the network to be assessed. d. Fundamental Research Efforts Comment:

1. Contractual terms and conditions include insurance, access requirements, and background checks.
2. Suppliers are contractually obligated to disclose component vulnerabilities, data loss, and security incidents.
3. The quality and interruption of supply are specifically mentioned in service agreements, though security is not called out.
4. Contractual terms and conditions include a specific section on information security requirements as well as consequences if there is a failure to comply with the requirements for security, quality, and integrity.
5. Contractual requirements include regular site visits, informal touchpoints, and supplier meetings. Most organizations communicate with suppliers on a regular basis via traditional enterprise communication methods,

including email, phone, communications platforms (e.g., Skype, Zoom, etc.), and supplier portals (e.g., iSupplier). Organizations also survey their critical suppliers annually to ensure people, data, and policies are maintained and up to date relative to supporting the contracts. These surveys include a variety of cybersecurity practices, such as supplier personnel receiving security training, physical security measures, use of security cameras and adequacy of camera recording storage, IT and network security measures, security organizational data on external networks, and assessment of applicable compliance levels. 1. Organizational realignment to mitigate supplier risks, such as dedicating personnel to assess supplier risks and effectively communicating them to executive leadership. 2. Operational technology (OT) risk reduction with most instances of prevention and monitoring (e.g., network segmentation, security information, and event management [SIEM] implementation) occurring on the OT portion of the acquirer networks. 3.

Three comments requested a narrow interpretation of the Freedom of Information Act (FOIA) exemptions, and one asked that the records not be exempted under Privacy Act provisions. Response: As recognized in the Background section of the Interim Rule (77 FR 27615 , at 27616), a foundational element of this program is the recognition that the information being shared includes extremely sensitive nonpublic information. This includes the GFI shared by the Government, as well as the information regarding cyber incidents that is shared by the DIB participants, which they typically treat as extremely sensitive proprietary, commercial, or operational information for which release and dissemination is tightly controlled. Accordingly, as stated in § 236.6 of the rule, confidentiality of such sensitive information exchanged under this program will be protected to the maximum extent authorized by law, regulation, and policy. This includes taking appropriate measures, including the use of any applicable exemptions under FOIA or the Privacy Act, to safeguard against unauthorized public disclosure and in full compliance with applicable laws, regulations, policies, and procedures (see § 236.2(c)(2)(vii) and § 236.5(h)). No change is made to the rule. Comment: Four comments addressed DoD working with private contractors without appropriate safeguards for privacy rights, maintaining a database on law abiding Americans and subverting due process and gathering information about an unsuspecting populace. Response:

- Data use denied because facility is inaccessible due to power failure. - Data is destroyed by fire. - Data base integrity damaged by effects of lightning. - Sensitive data disclosed because tornado scatters storage media and hardcopy outputs throughout uncontrolled access area. - Data validation and integrity checks' COMPUTER ABUSE Willful or negligent unauthorized activity that affects the availability, confidentiality, or integrity of computer resources. Computer abuse includes fraud, embezzlement, theft, malicious damage, unauthorized use, denial of service, and misappropriation. Levels of computer abuse are:

(A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (c)(4) because an exemption is being claimed for subsection (d) making this subsection not applicable. (C) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (D) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violation of laws or civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information be retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (E) From subsection (e)(2) because in a criminal investigation, the requirement that information be collected to the greatest extent possible from the subject individual would present a serious impediment to law enforcement in that the subject of the investigation would be placed on notice of the existence of the investigation and would therefore be able to avoid detection. (F) From subsection (e)(3) because the requirement that individuals supplying information be provided with a form stating the requirements of subsection (e)(3) would constitute a serious impediment to law enforcement in that it could compromise the existence of a confidential investigation, reveal the identity of confidential sources of information and endanger the life and physical safety of confidential informants. (G) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from access provisions of subsection (d) making these subsections not applicable. (H) From

subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (I) From subsection (e)(5) because in the collection of information for law (printed page 14749)

As discussed above, the Security Rule, as amended by the HITECH Act, specifically requires regulated entities to maintain reasonable and appropriate administrative, physical, and technical safeguards to ensure the confidentiality, integrity, and availability of ePHI; to protect against any reasonably anticipated threats or hazards to the security or integrity of ePHI and unauthorized uses or disclosures of ePHI; and ensure compliance with the Administrative Simplification provisions by officers and workforce members of regulated entities. [129] It is reasonable to anticipate that regulated entities will need to protect ePHI against cyberattacks and unauthorized uses and disclosures of ePHI by their workforce members. Experts estimate the costs to the U.S. from cyberattacks on health care facilities to be significant. [130] According to one study, health care data breach costs to affected organizations have increased by more than 50 percent since 2020, making health care data breaches more expensive than data breaches in any other sector, at an average cost of almost \$10.1 million per breach. [131] Yet these costs, though sizeable, do not fully take into account the practical implications of poor or ineffective cybersecurity protocols. A failure to implement adequate security measures may lead to: financial loss; reputational harm for affected individuals and affected regulated entities; privacy loss; and safety concerns. [132] Additionally, breaches of unsecured PHI may lead to identity theft, fraud, stock manipulation, and competitive disadvantage. [133] According to a study funded by the Institute for Critical Infrastructure Technology, victims of medical identity theft incur on average costs of \$13,500 to recover from that theft. [134] Unlike financial information, much of an individual's PHI is (printed page 908) immutable. For example, an individual's date and location of birth and their health history will not change, even if their address might. In contrast, an individual's passwords, bank account numbers, and other financial information can all be changed. Thus, PHI can continue to be exploited throughout an individual's lifetime, making PHI likely to be far more valuable than an individual's credit card information. [135] On the surface, the harms that result from a breach of ePHI or a cyberattack on a regulated entity's electronic information systems, as discussed above, are not significantly different than those that would result from a breach of information in another sector. However, the reality is, as discussed above, that the implications of such harms are far greater in the health care sector because of their potential to adversely affect an individual's health or quality of life, or even to cost an individual their life. [136]

(5) U.S. Army Criminal Investigation Command (USACIDC) reports of investigations (PA system of records notice A0195-2a USACIDC, Source Register; A0195-2b USACIDC, Criminal Investigation and Crime Laboratory Files) have been exempted from the amendment provisions of the Privacy Act. Requests to amend these reports will be considered under AR 195-2. Actions taken by the Commander of U.S. Army Criminal Investigation Command will constitute final action on behalf of the Secretary of the Army under that regulation. (6) Records placed in the National Archives are exempt from the Privacy Act provision allowing individuals to request amendment of records. Most provisions of the Privacy Act apply only to those systems of records that are under the legal control of the originating agency; for example, an agency's current operating files or records stored at a Federal Records Center. (7) Inspector General investigative files and action request/complaint files (records in system notice A0021-1 SAIG, Inspector General Records) have been exempted from the amendment provisions of the Privacy Act. Requests to amend these reports will be considered under AR 20-1 by the Inspector General. Action by the Inspector General will constitute final action on behalf of the Secretary of the Army under that regulation. (8) Other records that are exempt from the amendment provisions of the Privacy Act are listed in the applicable PA system of records notices. (c) Amendment procedures. (1) Requests to amend records should be addressed to the custodian or system manager of the records. The request must reasonably describe the records to be amended and the changes sought (e.g., deletion, addition, or amendment). The burden of proof is on the requester. The system manager or records custodian will provide the individual with a written acknowledgment of the request within 10 working days and will make a final response within 30 working days of the date the request was received. The acknowledgment must clearly identify the request and inform the individual that final action will be forthcoming within 30 working days. (2) Records for which amendment is sought must be reviewed by the proper system manager or custodian for accuracy, relevance, timeliness, and completeness. (3) If the amendment is appropriate, the system manager or custodian

will physically amend the records accordingly. The requester will be notified of such action. (4) If the amendment is not warranted, the request and all relevant documents, including reasons for not amending, will be forwarded to the proper Denial Authority within 10 working days to ensure that the 30 day time limit for the final response is met. In addition, the requester will be notified of the referral.

(i) NIST SP 800-171, titled "Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations," Revision 2, February 2020 (includes updates as of January 28, 2021) (NIST SP 800-171 R2), provides agencies with recommended security requirements for protecting the confidentiality of CUI when the information is resident in nonfederal systems and organizations; when the nonfederal organization is not collecting or maintaining information on behalf of a Federal agency or using or operating a system on behalf of an agency; and where there are no specific safeguarding requirements for protecting the confidentiality of CUI prescribed by the authorizing law, regulation, or governmentwide policy for the CUI category listed in the CUI Registry. The requirements apply to all components of nonfederal systems and organizations that process, store, and/or transmit CUI, or that provide protection for such components. The security requirements are intended for use by Federal agencies in contractual vehicles or other agreements established between those agencies and nonfederal organizations. This document is incorporated by reference as a foundational source for definitions and security requirements. (j) NIST SP 800-171A, titled "Assessing Security Requirements for Controlled Unclassified Information," June 2018 (NIST SP 800-171A Jun2018), provides Federal and non-Federal organizations with assessment procedures and a methodology that can be employed to conduct assessments of the CUI security requirements in NIST SP 800-171 R2. The assessment procedures are flexible and can be customized to the needs of the organizations and the assessors conducting the assessments. Security assessments can be conducted as self-assessments; independent, third-party assessments; or government-sponsored assessments and can be applied with various degrees of rigor, based on customer-defined depth and coverage attributes. The findings and evidence produced during the security assessments can facilitate risk-based decisions by organizations related to the CUI requirements. This document is incorporated by reference as a foundational source for definitions and assessment.

CM.L2-3.4.7 · Nonessential Functionality CMMC Assessment Guide · Level 2 | Version 2.13 107
principle of least functionality but does not specifically address which elements of a system should be limited. Example You are responsible for purchasing new endpoint hardware, installing organizationally required software to the hardware, and configuring the endpoint in accordance with the organization's policy. The organization has a system imaging capability that loads all necessary software, but it does not remove unnecessary services, eliminate the use of certain protocols, or close unused ports. After imaging the systems, you close all ports and block the use of all protocols except the following: · TCP for SSH on port 22; · SMTP on port 25; · TCP and UDP on port 53; and · HTTP and HTTPS on port 443. The use of any other ports or protocols are allowed by exception only [i,l,o]. Potential Assessment Considerations · Are only applications and services that are needed for the function of the system configured and enabled [a,b,c,d,e,f]? · Are only those ports and protocols necessary to provide the service of the information system configured for that system [g,h,i,j,k,l]? · Are systems services reviewed to determine what is essential for the function of that system [m]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.4.7

(Response) The final rule applies to persons who manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States, unless the person qualifies for an exclusion in § 1.327 of the final rule. An importer of record or an initial U.S. recipient that is involved in one or more of the identified activities must establish and maintain the required records. (Comment 18) Several comments express concern because the proposed regulation applies only to domestic, for-hire transporters, and foreign transporters that enter the United States, as well as domestic private transporters, are not covered. Comments state that the regulation should apply uniformly to all transporters, foreign and domestic, for-hire and private, to ensure that no group has an unfair competitive advantage. (Response) All persons transporting food in the United States must meet the requirements of subpart J of this final rule, regardless of whether they are ·for hire· or ·private·. FDA notes, however, that if a manufacturer located in the United States transports the food in its own company trucks, then it must comply with the recordkeeping requirements for nontransporters as opposed to those applicable to transporters because FDA does not need the facility to keep duplicative records of the food while it is in that facility's control. However, if a foreign person, such as a person who manufactures food, transports food in the United States, it

must comply with the requirements for transporters, even if it transports the food in the United States itself. This ensures that FDA will have the ability to traceback the food that is transported in the United States, even if the facility from which the food originates is an exempt foreign facility under subpart J. (Comment 19) One comment notes that CBP's current requirements apply to trucking companies that transport imported food into the United States. The comment suggests that FDA coordinate with CBP to get data from them in the event of a threat to the nation's food supply, rather than develop its own distinct recordkeeping regulations.

The Cyber AB marketplace (cyberab.org) is the official directory where organizations can find: - **C3PAOs**: Authorized third-party assessment organizations for CMMC Level 2 assessments - **RPOs**: Registered Provider Organizations that offer consulting and preparation services - **Registered Practitioners (RPs)**: Individual consultants certified to help with CMMC preparation - **Certified CMMC Assessors (CCAs)**: Individuals qualified to conduct assessments - **Certified CMMC Professionals (CCPs)**: Individuals with foundational CMMC knowledge All organizations and individuals listed in the marketplace have been vetted and authorized by the Cyber AB. Organizations seeking CMMC assessment or consulting should verify their provider is listed in the marketplace.

(E) Only a person trained in accordance with § 1045.120 10 CFR may classify matter containing TFNI. (F) Matter containing RD, FRD, and TFNI is not automatically declassified and only DOE-authorized persons may downgrade the category or declassify matter marked as containing RD. Only DOE or DoD authorized persons may downgrade the category or declassify matter marked as containing FRD. (G) How to submit a challenge if they believe RD, FRD, or TFNI information (e.g., a guide topic) or matter containing RD, FRD, or TFNI is not properly classified. (H) Access requirements for matter marked as containing RD or FRD. (ii) All persons with access to TFNI must receive initial and periodic refresher training as required under § 1045.120 10 CFR. This training may be combined with the training for access to RD and FRD. The training must include the following information: (A) What information is potentially TFNI. (B) Only a person with appropriate training may determine if matter contains TFNI. (C) Marking requirements for matter containing TFNI. (D) Matter containing TFNI is not automatically declassified and only DOE authorized persons may downgrade the category or declassify matter marked as containing TFNI. (E) How to submit a challenge if they believe TFNI information (e.g., a guide topic) or matter containing TFNI is not properly classified. (iii) Persons with access to RD, FRD, or TFNI must submit matter that potentially contains RD or FRD to an RD derivative classifier for review. If matter potentially contains TFNI, it must be submitted to a person trained to make TFNI determinations. Matter potentially containing RD, FRD, or TFNI must be reviewed, even if the potential RD, FRD, or TFNI is derived from the open literature. Prior to review, the matter must be marked as a working paper under 10 CFR 1045.140(c) . If the matter is intended for public release and potentially contains RD or TFNI, it must be submitted to the DOE for review. If the matter is intended for public release and contains FRD, it must be submitted to the DOE or the DoD. (iv) Only RD derivative classifiers may classify matter containing RD or FRD. RD derivative classifiers must receive initial training and refresher training every two years as required under 10 CFR 1045.120 . The training must include the content for persons with access to RD and FRD, along with the following: (A) The use of classification guides, classification bulletins, and portion-marked source documents to classify matter containing RD and FRD. (B) What to do if applicable classification guidance is not available. (C) Limitations on an RD derivative classifier's authority to remove RD or FRD portions from matter. (D) Marking requirements for matter containing RD and FRD.

(vi) Review proposed new, altered, and amended systems of records, to include submission of required notices for publication in the Federal Register and, when required, providing advance notification to the OMB and the Congress, consistent with 5 U.S.C. 552a , OMB Circular A-130, and DoD 5400.11-R. (vii) Review proposed DoD Component privacy rulemaking, to include submission of the rule to the Office of the Federal Register for publication and providing to the OMB and the Congress reports, consistent with 5 U.S.C. 552a , OMB Circular A-130, and DoD 5400.11-R. (viii) Develop, coordinate, and maintain all DoD computer matching agreements, to include the submission of required match notices for publication in the Federal Register and the provision of advance notification to the OMB and the Congress, consistent with 5 U.S.C. 552a , OMB Circular A-130, and DoD 5400.11-R. (ix) Provide advice and support to the DoD Components to ensure: (A) All information requirements developed to collect or maintain personal data conform to DoD Privacy Program standards; (printed page 18763) (B) Appropriate procedures and safeguards shall be developed, implemented, and maintained to protect personal information when it is stored in either a manual and/or automated

system of records or transferred by electronic or non-electronic means; and (C) Specific procedures and safeguards shall be developed and implemented when personal data is collected and maintained for research purposes. (x) Serve as the principal POC for coordination of privacy and related matters with the OMB and other Federal, State, and local governmental agencies. (xi) Compile and submit the Biennial Matching Activity Report to the OMB as required by OMB Circular A-130 and DoD 5400.11-R, and the Quarterly and Annual Federal Information Security Management Agency (FISMA) Privacy Reports, as required by 44 U.S.C. 3544(c), such other reports as may be required. (xii) Update and maintain this part and DoD 5400.11-R.

Subpart B-Systems of Records §.310.10 General. (a) **System of Records.** To be subject to the provisions of this part, a system of records must: (1) Consist of records (as defined in 310.4(r)) that are retrieved by the name of an individual or some other personal identifier; and (2) Be under the control of a DoD Component. (b) **Retrieval practices.** (1) Records in a group of records that MAY be retrieved by a name or personal identifier are not covered by this part even if the records contain personal data and are under control of a DoD Component. The records MUST be retrieved by name or other personal identifier to become a system of records for the purpose of this part. (i) When records are contained in an automated (Information Technology) system that is capable of being manipulated to retrieve information about an individual, this does not automatically transform the system into a system of records as defined in this part.

Making the user name the password makes the password easy to remember- and exceptionally easy to guess. Brand says he has never found a system that didn't have at least one Joe. Last summer, he says, 'While I was testing a series of sensitive systems where hundreds of thousands of dollars were spent to remove security | 7. | Need for data classification program (in conjunction with Legal Department) | X | |-----|-----
-----|-----|----| | 8 | Devising a
data classification program (in conjunction with Legal Department) | | X | | 9 | Evaluation of data
to detect errors and intentional misconduct | X | | 10 | Controlling security- related misconduct
by user-area employees | X | | 11 | Controlling security- related misconduct by DP staff | | X | |

12 | Preventing damage from technical intrusions by outsiders, such as through in-dial ports, wiretapping, etc. as may be cost-justified by users | | X | | 13 | Installing, maintaining, and administering access control programs, such as RACE. ACF2. TOP SECRET.

(E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. (23) System identifier and name. F033 USSC A, Information Technology and Control Records. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law, as a result of the maintenance of the information, the individual will be provided access to the information except to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (f)(23)(i). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Any portion of this system of records which falls within the provisions of 5 U.S.C. 552a(k)(2) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. (A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence. (B) From subsections (d) and (f) because providing access to investigative records and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding.

(4) Requests for personal information from Congress. These are processed in accordance with DoD Directive 5400.4 except those specific provisions in Subpart E-Disclosure of Personal Information to Other Agencies and Third Parties. §-310.4. Definitions. (a) Access . The review of a record or a copy of a record or parts thereof in a system of records by any individual. (b) Agency . For the purposes of disclosing records subject to the Privacy Act among the DoD Components, the Department of Defense is a considered a single agency. For all other purposes to include requests for access and amendment, denial of access or amendment, appeals from denials, and record keeping as relating to release of records to non-DoD Agencies, each DoD Component is considered an agency within the meaning of the Privacy Act. (c) Computer Matching Program . The computerized comparison of two or more automated systems of records or a system of records with non-Federal records. Manual comparison of systems of records or a system of records with non-Federal records are not covered. (d) Confidential source . A person or organization who has furnished information to the Federal Government under an express promise, if made on or after September 27, 1975, that the person's or the organization's identity shall be held in confidence or under an implied promise of such confidentiality if this implied promise was made on or before September 26, 1975. (e) Disclosure . The transfer of any personal information from a system of records by any means of communication (such as oral, written, electronic, mechanical, or actual review) to any person, private entity, or Government Agency, other than the subject of the record, the subject's designated agent or the subject's legal guardian. (f) Federal benefit program . A program administered or funded by the Federal Government, or by any agent or State on behalf of the Federal Government, providing cash or in-kind assistance in the form of payments, grants, loans, or loan guarantees to individuals. (g) Federal personnel . Officers and employees of the Government of the United States, members of the uniformed services (including members of the Reserve Components), individuals entitled to receive immediate or deferred retirement benefits under any retirement program of the United States (including survivor benefits). (h) Individual . A living person who is a citizen of

the United States or an alien lawfully admitted for permanent residence. The parent of a minor or the legal guardian of any individual also may act on behalf of an individual. Members of the United States Armed Forces are individuals. Corporations, partnerships, sole proprietorships, professional groups, businesses, whether incorporated or unincorporated, and other commercial entities are not individuals when acting in an entrepreneurial capacity with the Department of Defense but are individuals otherwise (e.g., security clearances, entitlement to DoD privileges or benefits, etc.). (i)

IA.L2-3.5.11 · Obscure Feedback CMMC Assessment Guide · Level 2 | Version 2.13 134 IA.L2-3.5.11 · OBSCURE FEEDBACK Obscure feedback of authentication information. ASSESSMENT OBJECTIVES [NIST SP 800-171A]118 Determine if: [a] authentication information is obscured during the authentication process. POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A]118 Examine [SELECT FROM: Identification and authentication policy; procedures addressing authenticator feedback; system security plan; system design documentation; system configuration settings and associated documentation; system audit logs and records; other relevant documents or records]. Interview [SELECT FROM: Personnel with information security responsibilities; system or network administrators; system developers]. Test [SELECT FROM: Mechanisms supporting or implementing the obscuring of feedback of authentication information during authentication]. DISCUSSION [NIST SP 800-171 REV. 2]

Assistant Secretary for Communications and Information, National Telecommunications and Information Administration. Footnotes 1. See, e.g., Cyberspace Policy Review: Assuring a Trusted and Resilient Information and Communications Infrastructure, May 29, 2009, at 1, http://www.whitehouse.gov/assets/documents/Cyberspace_Policy_Review_final.pdf (Cyberspace Policy Review), citing Director of National Intelligence, Annual Threat Assessment of the Intelligence Community for the Armed Services Committee, Statement for the Record, March 10, 2009, at 39. Back to Citation 2. See, e.g., id. at 2 (listing several examples of media reported incidents); see also David S. Wall, Cybercrime, Media and Insecurity: The Shaping of Public Perceptions of Cybercrime, 22 International Review of Law, Computers and Technology 45 (2008). A botnet, short for robot network, is an aggregation of compromised computers that are taken over via network connections without the knowledge or consent of their owners. Michigan Information Sharing and Analysis Center, Monthly Cyber Security Tips Newsletter (September 2007), http://www.michigan.gov/documents/cybersecurity/CSNewsletter_September2007_207450_7.pdf. Back to Citation 3. DHS oversees critical infrastructure protection, operates the United States Computer Emergency Readiness Team (US-CERT), oversees implementation of the Trusted Internet Connection initiative, and takes other actions to help secure both the federal civilian government systems and the private sector. DHS exercises primary responsibility within the executive branch for the operational aspects of Federal agency cybersecurity with respect to the Federal information systems that fall within the Federal Information Security Management Act of 2002 (FISMA). These responsibilities include overseeing the government-wide and agency-specific implementation of and reporting on cybersecurity policies and guidance; overseeing and assisting government-wide and agency-specific efforts to provide adequate, risk-based and cost-effective cybersecurity. Under FISMA, the Director of the Office of Management and Budget (OMB) oversees federal agency information security policies and practices, and OMB has directed all departments and agencies to coordinate and cooperate with DHS as necessary to carry out its FISMA responsibilities. OMB Memorandum M-10-28 Clarifying Cybersecurity Responsibilities and Activities of the Executive Office of the President and the Department of Homeland Security (DHS), http://www.whitehouse.gov/omb/assets/memoranda_2010/m10-28.pdf. Back to Citation 4. In addition, the Federal Communications Commission, an independent regulatory agency, is considering launching a voluntary certification program to encourage communications service providers to implement cybersecurity best practices. See http://hraunfoss.fcc.gov/edocs_public/attachmatch/FCC-10-63A1.pdf. Back to Citation

CIS Safeguard 7.3 · Perform Automated Operating System Patch Management Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis. Implementation Groups: 1,2,3 Asset Type: applications Security Function: protect Parent Control: Continuous Vulnerability Management

The Department proposes to modify the existing implementation specifications under the standard for access control and to add five new implementation specifications. Additionally, we propose to

redesignate the implementation specification for encryption and decryption as a standard. We propose to modify the implementation specification for unique user identification at 45 CFR 164.312(a)(2)(i) by renaming the implementation specification as 'Unique identification' and adding a requirement to assign a unique identifier for tracking each technology asset. These proposed modifications would clarify for regulated entities that the purpose of this requirement is to enable a regulated entity to identify and track unauthorized activity in its relevant electronic information systems. Such unauthorized activity may include activity by unauthorized persons or technology assets. It may also include activity by persons who are authorized to access the regulated entity's relevant information systems but who access ePHI that they do not need to access for their job or function. The Department also proposes to expand the types of identifiers a regulated entity may assign to users and technology assets beyond names to include numbers and/or other identifiers and to clarify that a unique identifier must be assigned to each user and technology asset in the regulated entity's relevant electronic information systems. This proposed modification would better meet the goals of this implementation specification by requiring a regulated entity to be able to discern and track activities among all users and technology assets, regardless of whether that user or technology asset is a person, hardware, software program, or device. The proposed implementation specification for unique identification aligns with the Department's essential CPG for Unique Credentials, which calls for regulated entities to use unique credentials to (printed page 966) help detect and track anomalous activities. [698] Additionally, we propose to add an implementation specification at proposed 45 CFR 164.312(a)(2)(ii) for administrative and increased access privileges. Access controls should enable an authorized user to access the minimum necessary information needed to perform their job functions. [699] Rights and/or privileges should be granted to authorized users based on the policies and procedures required under the administrative safeguard for information access management. [700] For example, a workforce member who has certain role-based administrative access privileges should have separate user identities for non-administrative access privileges and administrative access privileges. Separating a single workforce member's user identities based on access privilege substantially limits the risk that an intruder will be able to access ePHI through a workforce member's user identity when they are using the administrative access privileges. [701]

E.O. 13132 and published as part of the preambles to the final rules on February 20, 2003 [1024] and January (printed page 1009) 25, 2013. [1025] Regarding preemption, HIPAA dictates the relationship between State law and HIPAA regulatory requirements. [1026] The Health Information Technology for Economic and Clinical Health Act of 2009 (HITECH Act) provides that the HIPAA preemption provisions shall apply to the HITECH Act provisions and requirements. [1027] As explained by the House report that accompanied the American Recovery and Reinvestment Act of 2009, the HITECH Act would not only apply HIPAA's preemption provisions to the HITECH Act requirements, but it would also 'preserve the HIPAA privacy and security standards to the extent that they are consistent with' the HITECH Act. [1028] A requirement, standard, or implementation specification adopted in accordance with HIPAA and the HIPAA Rules supersedes any contrary provision of State law, subject to certain exceptions. [1029] Specifically, State law would be preempted under the Security Rule only when (1) a regulated entity finds it impossible to comply with both State and Federal requirements; or (2) the provision of State law stands as an obstacle to accomplishing and executing the purposes and objectives of the Administrative Simplification provisions or the HITECH Act. [1030] Although a few States (e.g., California and New York) have promulgated or are in the process of promulgating regulations pertaining to cybersecurity in health care that may be more stringent than the Security Rule, the Department believes that a regulated entity could comply with both sets of requirements by adhering to the more stringent standard. Thus, in such cases, the State law would not be an obstacle to the accomplishment and execution of HIPAA or the HITECH Act. The proposed modifications to the Security Rule would further the Congressional intent to improve the Medicare and Medicaid programs by the development of health information systems that are private and secure. The Department's proposals promote the safety, efficiency, and effectiveness of the health care system by refining the security standards established by Congress and implemented in the 2003 and 2013 Final Rules. The statute contemplated that the security measures adopted by all regulated entities, including State and local governments, would evolve over time in accordance with the security risks they face, and the NPRM proposals are in the nature of enhancing these existing requirements. Thus, the Department does not believe that the rule would impose substantial direct compliance costs on State and local governments that are not required by statute.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense 48 CFR Parts 204, 212, and 252 RIN 0750-AH58 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Proposed rule. SUMMARY: DoD is proposing to amend the Defense Federal Acquisition Regulation Supplement (DFARS) to provide a provision for offerors, if owned or controlled by another business entity, to identify the Commercial and Government Entity (CAGE) code and legal name of that business entity. DATES: Comments on the proposed rule should be submitted in writing to the address shown below on or before September 24, 2012, to be considered in the formation of the final rule. ADDRESSES: Submit comments identified by DFARS Case 2011-D044, using any of the following methods: · Regulations.gov: <http://www.regulations.gov> · Submit comments via the Federal eRulemaking portal by inputting ·DFARS Case 2011-D044· under the heading ·Enter keyword or ID· and selecting ·Search·. Select the link ·Submit a Comment· that corresponds with ·DFARS Case 2011-D044·. Follow the instructions provided at the ·Submit a Comment· screen. Please include your name, company name (if any), and ·DFARS Case 2011-D044· on your attached document. · Email: dfars@osd.mil · Include DFARS Case 2011-D044 in the subject line of the message. · Fax: 571-372-6094. · Mail: Defense Acquisition Regulations System, Attn: Ms. Veronica Fallon, OUSD(AT&L)DPAP/DARS, Room 3B855, 3060 Defense Pentagon, Washington, DC 20301-3060. Comments received generally will be posted without change to <http://www.regulations.gov>, including any personal information provided. To confirm receipt of your comment(s), please check www.regulations.gov, approximately two to three days after submission to verify posting (except allow 30 days for posting of comments submitted by mail). FOR FURTHER INFORMATION CONTACT: Ms. Veronica Fallon, telephone 571-372-6087. SUPPLEMENTARY INFORMATION: I. Background DoD proposes to collect the CAGE code and name from offerors, if owned or controlled by another business entity, in a new provision with an offeror's representations and certifications. The CAGE code is a five-character identification number used extensively within the Federal Government, and is administered by the Defense Logistics Information Service. A search feature for CAGE codes is available at http://www.logisticsinformationservice.dla.mil/cage_welcome.asp. CAGE codes for vendors located in the United States may be obtained via registration in the Central Contractor Registration (CCR) application, available at

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology (IT). ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in federal information systems. The keynote presentation was made by Eric Hudson and Steve Rabinowitz of the GAO, based on a GAO report titled Internet of Things: Information on Use by Federal Agencies [GAO20-577]. Mr. Hudson is a senior analyst with GAO's physical infrastructure team. Mr. Rabinowitz is also a senior analyst at GAO and has participated in a number of infrastructure-related studies. Their presentation had three components: - 56 of 90 agencies were using IoT, especially to control or monitor systems, control access to facilities, and track physical assets (vehicles, property). - 25 agencies were currently using IoT and planned to expand their use. - 13 agencies were neither using nor planning to use IoT, based on lack of return on investment, internal administrative hurdles, or the lack of a business case.

DFARS 252.204-7021 (Cybersecurity Maturity Model Certification Requirements) Requires CMMC certification at the level specified in the contract, effective Phase 1 November 10, 2025. Flow-down requirements: DFARS 252.204-7021 includes flow-down provisions requiring prime contractors to include the clause in subcontracts where CUI will be processed, stored, or transmitted. Subcontractors must meet the same security requirements as the prime.

). The Government is currently assessing where the organizationally-defined parameters within Revision 3 should be standardized and implemented on a governmentwide basis. As stated in the

benefits section of this rule, it is important for the Government to immediately implement requirements to protect CUI on non-Federal information systems; therefore, this proposed rule does not seek to implement NIST's most recent revision. The FAR Council anticipates that future rulemaking will be initiated to update NIST SP 800-171 and NIST SP 800-171A to the current version.

V. Specific Questions for Public Comment To understand the exact scope of this impact and how this impact could be affected in the final rule, DoD, GSA, and NASA welcome input on the following questions regarding anticipated impact on affected parties. DoD, GSA, and NASA recognize that some agencies may need to tailor the approach to the information collected based on the unique mission and risks for their agency.

1. Is there additional information or guidance you view as necessary to effectively comply with this rule?
2. Are there specific situations you anticipate where your organization will be required to report on different timelines in order to comply with the CUI incident reporting requirements outlined in this proposed rule, other Federal contract requirements, or other regulations promulgated under Federal law? How would your organization handle disparate incident reporting timelines in other Federal Government contracting requirements or from other regulatory agencies?
3. Incident response and associated reporting are often iterative processes, with system owners updating reports as a situation evolves and more data becomes available. What implications are there for your organization, including with respect to incident response, to meet disparate timelines for incident reporting?
4. How much, if at all, would you estimate that the initial reporting requirement described in this proposed rule could increase the price of the products or services your organization provides to the Federal Government?
5. Understanding evolving data capabilities may change the nature or sensitivity of information over time, are there specific concerns not adequately addressed in this proposed rule? If possible, please provide any relevant use cases.
6. The FAR Council notes there is also what is referred to as "CUI specified", which is information that is considered CUI, but is also required to be handled in a certain way due to other laws, regulations, and policies (e.g., restrictions on disseminating information to foreign nationals or dual citizens under International Traffic in Arms Regulations (ITAR)). For CUI specified information, not only does it have to be treated and handled as CUI, (printed page 4287)

) that is subject to controls on the access, use, reproduction, modification, performance, display, release, disclosure, or dissemination. Controlled technical information is to be marked with one of the distribution statements B through F, in accordance with Department of Defense Instruction 5230.24, "Distribution Statements of Technical Documents." The term does not include information that is lawfully publicly available without restrictions. "Technical Information" means technical data or computer software, as those terms are defined in Defense Federal Acquisition Regulation Supplement clause 252.227-7013, "Rights in Technical Data-Noncommercial Items" (48 CFR 252.227-7013). Examples of technical information include research and engineering data, engineering drawings, and associated lists, specifications, standards, process sheets, manuals, technical reports, technical orders, catalog-item identifications, data sets, studies and analyses and related information, and computer software executable code and source code; (ii) Information subject to export control under the International Traffic in Arms Regulations (ITAR) (http://pmddtc.state.gov/-regulations_-laws/-itar_-official.html), or the Export Administration Regulations (EAR). (15 CFR part 730); (iii) Information designated as Critical Program Information (CPI) in accordance with DoD Instruction 5200.39, "Critical Program Information (CPI) Protection within the Department of Defense"; (iv) Critical Information (Operations Security) includes specific facts identified through the Operations Security process about friendly intentions, capabilities, and activities vitally needed by adversaries for them to plan and act effectively so as to guarantee failure or unacceptable consequences for friendly mission accomplishment (part of Operations Security process as described in 5205.02-M, "DoD Operations Security (OPSEC Program Manual)"; (v) Personally Identifiable Information (PII) that can be used to distinguish or trace an individual's identity in accordance with DoD Directive 5400.11, "DoD Privacy Program"; (vi) Information bearing current and prior designations indicating controlled unclassified information (e.g., For Official Use Only, Sensitive But Unclassified, and Limited Official Use, DoD Unclassified Controlled Nuclear Information, Sensitive Information) that has not been cleared for public release in accordance with DoD Directive 5230.29, "Clearance of DoD Information for Public Release" (see also DoD 5200.01 M Volume 4, "DoD Information Security Program: Controlled Unclassified Information (CUI)"); or (vii) Any other information that is exempt from mandatory public disclosure under DoD Directive 5400.07, "DoD Freedom of Information Act (FOIA) Program", and DoD Regulation 5400.7-R, "DoD Freedom of Information Program".

(d) Covered DIB systems means an information system that is owned or operated by or for a DIB participant and that

processes, stores, or transmits covered defense information. (e)

FAR Subpart 4.19 and DFARS Subpart 204.73 address safeguarding of FCI and CUI in contractor information systems and prescribe contract clauses requiring protection of FCI and CUI within the supply chain. The FAR and DFARS requirements for safeguarding FCI and CUI predate the CMMC Program by many years, and baseline costs for their implementation are assumed to vary widely based on factors including, but not limited to, company size and complexity of the information systems to be secured. FAR 52.204-21, Basic Safeguarding of Covered Contractor Information Systems, is prescribed at FAR section 4.1903 for use in solicitations and contracts when the contractor or subcontractor at any tier may have FCI residing in or transiting through its information system. This clause requires contractors and subcontractors to apply basic safeguarding requirements and procedures to protect applicable contractor information systems that process, store, or transmit FCI. In addition, DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting, is prescribed at DFARS section 204.7304(c) for use in DoD in all solicitations and contracts, including solicitations and contracts using FAR part 12 procedures for the acquisition of commercial items, except for solicitations and contracts solely for the acquisition of commercially available off-the-shelf items. This clause applies when a contractor information system processes, stores, or transmits covered defense information and requires contractors and subcontractors to provide adequate security to safeguard that information when it resides on or transits through a contractor information system, and to report cyber incidents that affect that system or network. The clause states that to provide adequate security, the contractor shall implement, at a minimum, the security requirements in National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 Rev 2, Protecting CUI in Nonfederal Systems and Organizations. Contractors are also required to flow down DFARS clause 252.204-7012 to all subcontracts for operationally critical support or for which subcontractor performance will involve covered defense information. However, neither FAR clause 52.204-21 nor DFARS clause 252.204-7012 provide for DoD assessment of a contractor's implementation of the information protection requirements required by those clauses. The Department developed the CMMC Program to verify implementation of cybersecurity requirements in DoD contracts and subcontracts, by assessing (printed page 89080) adequacy of contractor information system security compliance prior to award and during performance of the contract. With limited exceptions, the Department intends to require compliance with CMMC as a condition of contract award. Once CMMC is implemented, the required CMMC Level for contractors and subcontractors will be specified in the solicitation and Requests for Information (RFIs), if utilized.

. Army policy concerning the privacy rights of individuals and the Army's responsibilities for compliance with the Privacy Act are as follows: (1) Protect the privacy of United States living citizens and aliens lawfully admitted for permanent residence from unwarranted intrusion. (2) Deceased individuals do not have Privacy Act rights, nor do executors or next-of-kin in general. However, immediate family members may have limited privacy rights in the manner of death details and funeral arrangements of the deceased individual. Family members often use the deceased individual's Social Security Number (SSN) for federal entitlements; appropriate safeguards must be implemented to protect the deceased individual's SSN from release. Also, the Health Insurance Portability and Accountability Act extends protection to certain medical information contained in a deceased individual's medical records. (3) Personally identifiable health information of individuals, both living and deceased, shall not be used or disclosed except for specifically permitted purposes. (4) Maintain only such information about an individual that is necessary to accomplish the Army's mission. (5) Maintain only personal information that is timely, accurate, complete, and relevant to the collection purpose. (6) Safeguard personal information to prevent unauthorized use, access, disclosure, alteration, or destruction. (7) Maintain records for the minimum time required in accordance with an approved National Archives and Records Administration record disposition. (8) Let individuals know what Privacy Act records the Army maintains by publishing Privacy Act system of records notices in the Federal Register . This will enable individuals to review and make copies of these records, subject to the exemptions authorized by law and approved by the Secretary of the Army. Department of the Army Privacy Act systems of records notices are available at <http://www.defenselink.mil/-/privacy> . (9) Permit individuals to correct and amend records about themselves which they can prove are factually in error, not timely, not complete, not accurate, or not relevant. (10) Allow individuals to request an administrative review of decisions that deny them access to or the right to amend their records. (11) Act on all requests promptly, accurately, and fairly. (12) Keep paper and electronic records that are retrieved by name or personal identifier only in approved Privacy Act systems of records. (13) Maintain no records describing how

an individual exercises his or her rights guaranteed by the First Amendment (freedom of religion, freedom of political beliefs, freedom of speech and press, freedom of peaceful assemblage, and petition) unless expressly authorized by statute, pertinent to and within the scope of an authorized law enforcement activity, or otherwise authorized by law or regulation.

and compromise protective services provided to the President and other individuals. Amendment of such records could also impose a highly impracticable administrative burden by requiring investigations to be continuously reinvestigated. (4) Exemption (k)(5). Personnel investigations and vetting records may contain investigatory material compiled solely for determining suitability, eligibility, and qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information. In some cases, such records may contain information pertaining to the identity of a source who furnished information to the Government under an express promise that the source's identity would be held in confidence (or prior to the effective date of the Privacy Act, under an implied promise). Application of exemption (k)(5) for such records may be necessary because access to, amendment of, or release of the accounting of disclosures of such records could identify these confidential sources who might not have otherwise come forward to assist the Government, could hinder the Government's ability to obtain information from future confidential sources, and result in an unwarranted invasion of the privacy of others. Amendment of such records could also impose a highly impracticable administrative burden by requiring investigations to be continuously reinvestigated. (5) Exemption (k)(6). Personnel investigations and vetting records may contain information relating to testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service. Application of exemption (k)(6) for such records may be necessary because access to, amendment of, or release of the accounting of disclosures of such records could compromise the objectivity and fairness of the testing or examination process. Amendment of such records could also impose a highly impracticable administrative burden by requiring investigations to be continuously reinvestigated. (6) Exemption (k)(7).

(B) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(4), (d), (e)(4)(G), and (f). (ii) Authority. 5 U.S.C. 552a(j)(2) . (iii) Reasons. (A) Granting individuals access to records maintained by this Board could interfere with internal processes by which Board personnel are able to formulate decisions and policies with regard to clemency and parole in cases involving naval prisoners and other persons under the jurisdiction of the Board. Material will be screened to permit access to all material except such records or documents as reflecting items of opinion, conclusion, or recommendation expressed by individual board members or by the board as a whole. (B) The exemption of the individual's right to access to portions of these records, and the reasons therefore, necessitate the partial exemption of this system of records from the requirements of the other cited provisions. (19) System identifier and name. N01752-1, Family Advocacy Program System. (i) Exemptions. (A) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, military service, Federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (C) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3) and (d). (ii) Authority. 5 U.S.C. 552a(k)(2) and (k)(5) . (iii) Reasons. (A) Exemption is needed in order to encourage persons having knowledge of abusive or neglectful acts toward children to report such information, and to protect such sources from embarrassment or recriminations, as well as to protect their right to privacy. It is essential that the identities of all individuals who furnish information under an express promise of confidentiality be protected. Additionally, granting individuals access to information relating to criminal and civil law enforcement, as well as the release of certain disclosure accounting, could interfere with ongoing investigations and the orderly administration of justice, in that it could result in the concealment, alteration, destruction, or fabrication of information; could hamper the identification of offenders or alleged offenders and the disposition of charges; and could jeopardize the safety and well-being of parents and their children. (printed page 14769)

20. Usability, expense, and support issues are significant considerations in selection of authentication and authorization controls. Most of these systems identify the user. Where the identity of the user is important to a system's access policy, issuance and maintenance of credentials depends on an underlying identity management system. Effective identity management systems establish one party's identity to another party's satisfaction, increasing consumer trust in the use of the Internet, while balancing the security and privacy concerns of all users involved. It is worthwhile to remember that users are not a homogeneous group. They consist of individuals, and small, medium, and large enterprises, both public and private. The diversity of the characteristics among these various categories of users means that each group will make selections among various security solutions based on different criteria that address their unique needs and economic drivers. Privacy considerations also significantly complicate identification based on personally identifiable information. For many purposes, identification needs to simply associate the user's request for access or service with an institutional authorization by the entity that is providing the access or service. By contrast, more sensitive transactions (e.g., online banking or exchange of electronic health records) may require authentication of more of an individual's identifying characteristics. Various audit and enforcement functions benefit from identification of the access with a specific person, but this is not necessary for all use cases. Back to Citation

21. National Strategy for Secure Identities in Cyberspace, at 1 (June 25, 2010), available at http://www.dhs.gov/xlibrary/assets/ns_tic.pdf . Back to Citation

22. More information about the US Common Criteria assurance scheme is available at <http://www.commoncriteriaportal.org/theccra.html> . Back to Citation

23. For more information, please visit <http://cybersecurity.nitrd.gov> . Back to Citation

24. The market for cyber insurance was estimated to be \$350 million in 2005, from a negligible amount almost a decade earlier. George Mason University School of Law, Critical Infrastructure Protection Program, The CIP Report, at 2 (Sept. 2007), http://cip.gmu.edu/archive/cip_report_6.3.pdf . Back to Citation

[FR Doc. 2010-18507 Filed 7-27-10; 8:45 am] BILLING CODE 3510-13-P

(3) The contractor will maintain a record of all COMSEC briefings as specified by the appropriate COR. (f) U.S. classified cryptographic information access briefing and debriefing requirements. (1) U.S. classified cryptographic information does not include seed key or controlled cryptographic items. (2) A contractor's employee may be granted access to U.S. classified cryptographic information only if the employee: (i) Is a U.S. citizen. (ii) Has a final USG-issued eligibility determination appropriate to the classification of the U.S. cryptographic information to be accessed. (iii) Has a valid need-to-know to perform duties for, or on behalf of, the USG. (iv) Receives a security briefing appropriate to the U.S. Classified Cryptographic Information to be accessed. (v) Acknowledges the granting of access to classified information by executing Section I of Secretary of Defense (SD) Form 572, Cryptographic Access Certification and Termination (available at: <https://www.esd.whs.mil/Portals/54/Documents/DD/forms/sd/sd0572.pdf>). (vi) Where so directed by a USG department or agency head, acknowledges the possibility of being subject to a CI scope polygraph examination that will be administered in accordance with department or agency directives and applicable law. (3) An employee granted access to cryptographic information will be debriefed and execute Section II of the SD 572 not later than 90 days from the date access is no longer required. (4) The contractor will maintain the SD 572 for a minimum of five years following the debriefing. (5) Cryptographic access briefings must fully meet the requirements of paragraph (e) of this section. (printed page 83360) (g) Destruction and disposition of COMSEC material. The appropriate GCA representative, e.g., the contracting officer representative, will provide directions to the contractor when accountable COMSEC material is to be destroyed. These directions may be provided in superseding editions of publications or by specific instructions. (h) Subcontracting COMSEC work. Subcontracts requiring the disclosure of classified COMSEC information will be awarded only upon the written approval of the GCA. (i) Unsolicited proposals. Any unsolicited proposal for a COMSEC system, equipment, development, or study that may be submitted by a contractor to a USG agency will be forwarded to the Deputy National Manager for National Security Systems for review and follow up action at: Deputy National Manager for National Security Systems, NSA, Fort George G. Meade, MD 20755-6000. § 117.22 DHS CCIPP. (a) General. DHS will coordinate with other USG agencies that have an equity with a private sector entity and the CCIPP in accordance with § 117.6(f). (b) Authority.

The CFR is the codification of the Federal Government's rules and regulations published in the Federal Register . The CFR was created with the passage of the Federal Register Act and amended in 1937 to provide a codification of all regulations at least once a year. The CFR reflects the tenet

that the Federal Government must follow an open public process when rulemaking. Due to the broad application of CMMC requirements for DoD acquisition support by the defense industrial base, the Department determined that codifying the CMMC Program and its associated requirements in 32 CFR part 170 CMMC Program rule (for national defense and security) was needed in conjunction with the corresponding DFARS contractual requirements codified in 48 CFR part 204 CMMC Acquisition rule. The DoD has no authority to make CMMC a Federal-wide program. The notice of the required CMMC level is provided at time of solicitation. This does not prohibit contractors from pursuing CMMC assessments prior to receipt of a solicitation. DoD declines to comment on the reposting of information being reported in the media.

32. Administrative Changes to Terms, References and Notations Comment: Over 160 comments asked for clarification of terminology or the addition, removal, or modification of a definition. Most requests focused on Security Protection Data and Assets, Senior Officials, Information System, External Service Providers, Cloud Service Providers, Managed Support Providers, Internet of Things, CMMC Security Requirements, Organization Seeking Assessment, and Organization Seeking Certification. Numerous comments recommended the following terms could be clarified, expanded, or defined: ·Defense Industrial Base·, ·personal information·, ·contractor·, ·sub-contractor·, ·Prime Contractor·, ·equipment·, ·contractor information system·, ·Information System·, ·system·, ·Information Resource·, ·CMMC Approved Training Materials (CATM)·, ·CMMC Certified Instructor (CCI)·, ·Provisional Instructor (PI)·, ·cyber incident·, ·Accreditation Body·, ·Assessment Findings Report·, ·Organizationally-Defined·, ·Organizationally-Defined Parameter (ODP)·, ·Periodically·, ·Risk Assessment·, ·Risk Analysis·, Supervisory Control·, Data Acquisition·, ·Operationally Critical Support·, ·System Security Plan (SSP)·, ·TTP·, ·CMMC·, ·COTS·, ·NARA·, ·C3PAO·, ·IS·, ·NSS·, ·Technology Asset·, ·Personnel Assets·, ·Asset Categories·, ·DIBCAC High·, and ·Enterprise·. Response: All requests for changes to terminology definitions, references, and usage have been reviewed. In response, many terms were updated in §170.4 Acronyms and definitions. The DoD determined those terms that were not changed to be sufficiently defined and appropriately referenced, and the requested administrative changes would not have resulted in a substantive change.

a. SPA/SPD/Asset Comment:

systems, but such standards and guidelines shall not apply to national security systems without the express approval of the appropriate federal officials exercising policy authority over such systems. This guideline is consistent with requirements of the Office of Management and Budget (OMB) Circular A-130. Nothing in this publication should be taken to contradict the standards and guidelines made mandatory and binding on federal agencies by the Secretary of Commerce under statutory authority. Nor should these guidelines be interpreted as altering or superseding the existing authorities of the Secretary of Commerce, OMB Director, or any other federal official. This publication may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST. National Institute of Standards and Technology Special Publication 800-172 Natl. Inst. Stand. Technol. Spec. Publ. 800-172, 84 pages (February 2021) CODEN: NSPUE2 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-172> Certain commercial entities, equipment, or materials may be identified in this document to describe an experimental procedure or concept adequately. Such identification is not intended to imply recommendation or endorsement by NIST, nor is it intended to imply that the entities, materials, or equipment are necessarily the best available for the purpose. There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts, practices, and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative.

1. a plethora of reports on security violations over the last two decades that have plagued private. State and Federal organizations; 2. the growing concern of the U.S. Government on the matter of computer security^^ - - Privacy Act of 1974 [USPL74] -[to amend title 5, United States Code ...

3.0.6 System Supplier: Encore Computer Corporation System Hardware: 91 Series Model: 91-02427 C Compiler: Green Hills Software, Inc.

(Response) FDA acknowledges the difficulties in addressing regulatory flexibility considerations with staggered compliance dates. Nevertheless, FDA has decided that staggering the compliance dates is a viable mechanism to address regulatory flexibility considerations without compromising the effectiveness of the regulation as intended by Congress when it enacted section 306 of the

Bioterrorism Act. However, to address the concerns expressed by these comments without compromising the effectiveness of the regulation, in the final rule compliance dates for all size businesses have been extended by 6 months to 12 months for large, 18 months for small, and 24 months for very small businesses. FDA further notes that small and very small businesses are not required by FDA to comply earlier than these timeframes even if they are doing business with larger businesses that have earlier compliance dates. (Comment 218) At least one comment suggests that requiring the same compliance date for all firms and excluding small businesses from complying with the regulation compromises the effectiveness of the regulation due to breaks in the recordkeeping chain during traceback investigations. Such a compromise is contrary to the intent of the Regulatory Flexibility Act. (Response) In the PRIA, FDA considered three regulatory flexibility options: (1) Exempting small business from all regulatory requirements, (2) offering small business exemptions from parts of the regulation, and (3) specifying longer effective compliance dates for small businesses. We found that specifying longer compliance dates for small businesses was one option that would not appreciably compromise the purpose of the regulation. (Comment 219) Several comments state that the 4 and 8 hour provision for records access is more onerous for small businesses and suggest either flexibility in the extent of the records to be made available in that time period for small businesses, or extending the records access time requirements for small businesses. One comment suggests that the rule requires firms to keep more records than is necessary and that FDA should consider relaxing the level of detail in the small business records required to be made available in the 4 and 8-hour records access times. One comment states that the burden on a small firm from devoting a single employee, who generally performs multiple tasks, to accessing requested records is greater than that on a large firm devoting an employee who may generally perform only one task.

; (d); (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I); and (f). Exemptions from these particular subsections are justified, on a case-by-case basis to be determined at the time a request is made, for the following reasons: (A) From subsection (c)(3) and (c)(4) (Accounting for Disclosures) because release of the accounting of disclosures could alert the subject of an investigation of an actual or potential criminal, civil, or regulatory violation to the existence of that investigation and reveal investigative interest on the part of NGA as well as the recipient agency. Disclosure of the accounting would therefore present a serious impediment to law enforcement efforts and/or efforts to preserve national security. Disclosure of the accounting would also permit the individual who is the subject of a record to impede the investigation, to tamper with witnesses or evidence, and to avoid detection or apprehension, which would undermine the entire investigative process. (B) From subsection (d) (Access to Records) because access to the records contained in this system of records could inform the subject of an investigation of an actual or potential criminal, civil, or regulatory violation to the existence of that investigation and reveal investigative interest on the part of NGA or another agency. Access to the records could permit the individual who is the subject of a record to impede the investigation, to tamper with witnesses or evidence, and to avoid detection or apprehension. Amendment of the records could interfere with ongoing investigations and law enforcement activities and would impose an unreasonable administrative burden by requiring investigations to be continually reinvestigated. In addition, permitting access and amendment to such information could disclose security-sensitive information that could be detrimental to homeland security. (C) From subsection (e)(1) (Relevancy and Necessity of Information) because in the course of investigations into potential violations of Federal law, the accuracy of information obtained or introduced occasionally may be unclear, or the information may not be strictly relevant or necessary to a specific investigation. In the interests of effective law enforcement, it is appropriate to retain all information that may aid in establishing patterns of unlawful activity. (D) From subsection (e)(2) (Collection of Information from Individuals) because requiring that information be collected from the subject of an investigation would alert the subject to the nature or existence of the investigation, thereby interfering with that investigation and related law enforcement activities. (E) From subsection (e)(3) (Notice to Subjects) because providing such detailed information could impede law enforcement by compromising the existence of a confidential investigation or reveal the identity of witnesses or confidential informants.

From the NIST SP 800-172 Rev 3 Final Public Draft: The Requirements 423 This section describes enhanced security requirements that are designed to protect the confidentiality, integrity, and availability of CUI in nonfederal systems and organizations. The enhanced security requirements are not required for any particular category or article of CUI. However, if a federal agency determines that CUI is associated with a critical program or a high value asset, the CUI and the system that processes, stores, or transmits such information are potential targets for the APT and, therefore,

may require increased protection. Such protection is expressed through the enhanced security requirements and is mandated by a federal agency in a contract, grant, or other agreement. The enhanced security requirements are selected either comprehensive

(Response) FDA's record access authority under sections 414(a) and 704(a) of the FD&C Act became effective upon enactment of the Bioterrorism Act on June 12, 2002. The record access provisions of the Bioterrorism Act do not require FDA to issue implementing regulations. FDA intends to issue guidance to FDA personnel regarding FDA's exercise of this provision in accordance with FDA's GGP's regulations (§10.115). The previously stated comments will be considered as FDA develops the agency's guidance. FDA does not agree that these procedures need to be codified. (Comment 151) One comment observes that, depending on the length of the distribution chain involved in a contamination event, FDA may need to examine records of numerous food handling facilities. As a result, it could still take FDA several days to obtain needed records. The comment suggests that source labeling could help FDA determine the ultimate source faster. (Response) The comment's suggestion is outside the scope of the proposed rule. The authority granted in section 306 of the Bioterrorism Act relates to establishing requirements for records to identify immediate previous sources and recipients of food, not establishing labeling requirements. (Comment 152) One comment requests specific guidelines and an opportunity to object to providing the records for a period before access of the records. (Response) FDA disagrees. FDA does not currently provide a period of time in which a person subject to an inspection may object prior to that inspection. As discussed in response to comment 171 of this document, FDA plans to issue a guidance document regarding the record access provisions. M. Comments on What Records Are Excluded From This Subpart? (Proposed §1.362) (Comment 153) Several comments express concern that information that FDA would view, copy, or otherwise access could contain confidential information, such as confidential commercial or trade secret information. Two comments ask FDA to permit a person subject to the requirements of section 414 of the FD&C Act to redact what they consider to be nonpublic information from records properly sought by FDA. One comment asks FDA to permit a person to create a separate document containing only that information FDA is entitled to inspect. Examples of confidential information that comments have described include formulas, recipes, information about their businesses, where the product was purchased or sold, product development information, and location and business operations of farms. One comment requests that FDA allow the affected person to either redact confidential information from the source records (purchase orders, bills of lading, etc.), or create separate records containing the information required by section 414 of the FD&C Act, but not including the information excluded by §1.362 of this final rule or any other confidential information.

3.5.2 Installation 1. 3.5.2 Setup Instructions 1. 3.5.2 Disabling of Unsecure services on Network Devices Use the following guidelines to disable unsecure services on all Allen Bradley devices of the Plant: 1.

Computer matching publication and review requirements. 310.53 Computer matching agreements (CMAs). Appendix A to Part 310-Safeguarding Personally Identifiable Information Appendix B to Part 310-Sample Notification Letter (printed page 18759) Appendix C to Part 310-DoD Blanket Routine Uses Appendix D to Part 310-Provisions of the Privacy Act From Which a General or Specific Exemption May Be Claimed Appendix E to Part 310-Sample of New or Altered System of Records Notice in Federal Register Format Appendix F to Part 310-Format for New or Altered System Report Appendix G to Part 310-Sample Amendments or Deletions to System Notices in Federal Register Format Appendix H to Part 310-Litigation Status Sheet Authority: Pub. L. 93-579, 88 Stat. 1896 (5 U.S.C. 552a). Subpart A-DoD Policy §310.1 Reissuance. This part consolidates into a single location (32 CFR part 310) Department of Defense (DoD) policies and procedures for implementing the Privacy Act of 1974, as amended (5 U.S.C. 552a) by authorizing the development, publication and maintenance of the DoD Privacy Program set forth by DoD Directive 5400.11 [1] and 5400.11-R, [2] both entitled: 'DoD Privacy Program.' §310.2 Purpose. This part: (a) Updates policies and responsibilities of the DoD Privacy Program under 5 U.S.C. 552a and OMB Circular A-130. (b) Authorizes the Defense Privacy Board, the Defense Privacy Board Legal Committee, and the Defense Data Integrity Board. (c) Continues to authorize the publication of DoD 5400.11-R. (d) Continues to delegate authorities and responsibilities for the effective administration of the DoD Privacy Program. §310.3 Applicability and scope. This part: (a) Applies to the Office of the Secretary of Defense (OSD), the Military Departments, the Chairman of the Joint Chiefs of Staff, the Combatant Commands, the Office of the Inspector General of the Department of Defense (IG, DoD), the Defense Agencies, the DoD Field Activities, and all other

organizational entities in the Department of Defense (hereinafter referred to collectively as the DoD Components). (b) Shall be made applicable to DoD contractors who are operating a system of records on behalf of a DoD Component, to include any of the activities, such as collecting and disseminating records, associated with maintaining a system of records. (c) This part does not apply to: (1) Requests for information made under the Freedom of Information Act. They are processed in accordance with DoD 5400.7-R. [3] (2) Requests for information from systems of records controlled by the Office of Personnel Management (OPM), although maintained by a DoD Component. These are processed in accordance with policies established by OPM Privacy Procedures for Personnel Records (5 CFR 297). (3) Requests for personal information from the General Accounting Office. These are processed in accordance with DoD Directive 7650.1. [4]

Disposition procedures . Clearly state that the records used in the match will be retained only for the time required for conducting the match. Once the matching purpose has been achieved, the records will be destroyed unless the records must be retained as directed by other legal authority. Unless the source agency requests that the records be returned, identify the means by which destruction will occur, i.e., shredding, burning, electronic erasure, etc. (12) Comptroller General access . Include a statement that the Comptroller General may have access to all records of the recipient agency to monitor or verify compliance with the terms of the CMA. (13) Cost-benefit analysis . (printed page 18783) (i) A cost-benefit analysis shall be conducted for the proposed computer matching program unless: (A) The Data Integrity Board waives the requirement, or (B) The matching program is required by a specific statute. (ii) The analysis must demonstrate that the program is likely to be cost-effective. This analysis is to ensure agencies are following sound management practices. The analysis provides an opportunity to examine the programs and to reject those that will only produce marginal results. Appendix A to Part 310 Safeguarding Personally Identifiable Information (PII) (See § 310.13 of Subpart B) A. General 1. The IT environment subjects personal information to special hazards as to unauthorized compromise, alteration, dissemination, and use. Therefore, special considerations must be given to safeguarding personal information in IT systems consistent with the requirements of DoD Directive 8500.1 and DoD Instruction 8500.2. 2. Personally identifiable information must also be protected while it is being processed or accessed in computer environments outside the data processing installation (such as, remote job entry stations, terminal stations, minicomputers, microprocessors, and similar activities). 3. IT facilities authorized to process classified material have adequate procedures and security for the purposes of this Regulation. However, all unclassified information subject to this Regulation must be processed following the procedures used to process and access information designated For Official Use Only. (See DoD 5200.1-R.) B. Risk Management and Safeguarding Standards 1. Establish administrative, technical, and physical safeguards that are adequate to protect the information against unauthorized disclosure, access, or misuse. (See OMB Circular A-130 and DoD Instruction 8500.2.) 2. Tailor safeguards to the type of system, the nature of the information involved, and the specific threat to be countered. C. Minimum Administrative Safeguards The minimum safeguarding standards as set forth in § 310.13(b) apply to all personal data within any IT system. In addition: 1. Consider the following when establishing IT safeguards: a. The sensitivity of the data being processed, stored and accessed. b. The installation environment. c. The risk of exposure.

facility security, network security). When making this decision, regulated entities should consider basic questions, such as: Has the organization agreed upon, and clearly identified and documented, the responsibilities of the Security Official? How are the roles and responsibilities of the Security Official crafted to reflect the size, complexity, and technical capabilities of the organization? NIST guidance urges the regulated entity to select a workforce member who is able to assess the effectiveness of security to serve as the point of contact for security policy, implementation, and monitoring. [543] It further recommends that a regulated entity should document the responsibilities in a job description and communicate this assigned role to the entire organization. NIST provides additional sample items for consideration by a regulated entity organizing its security practices, including identifying the workforce members in the organization who oversee the development and communication of security policies and procedures, direct IT security purchasing and investment, and ensure that security concerns have been addressed in system implementation. NIST also offers that a regulated entity should ask whether the security official has adequate access and communications with senior officials in the organization and whether there is a (printed page 948) complete job description that accurately reflects assigned security duties and responsibilities. k. Section 164.308(a)(9)(i) Standard: Workforce Security The purpose of the workforce security standard is to ensure that workforce members only have access to ePHI that

they need to perform their assigned functions and are prevented from accessing ePHI that they are not authorized to access to perform such functions. The proposed changes to the standard and implementation specifications would clarify the actions required of a regulated entity to assure such limits. Individuals have been harmed in the past by the failure of regulated entities to comply with the Security Rule requirements for workforce security. For example, a former employee of a large covered entity was able to access their former worksite and workstation using still-active credentials for more than a week after their employment was terminated. [544] OCR's investigation found evidence of a potential failure to terminate the former employee's access to PHI, which enabled the former employee to download the ePHI of nearly 500 individuals, including their names, addresses, dates of birth, race/ethnicity, gender, and sexually transmitted infection test results onto a USB drive. This type of real-world experience and OCR's observations more broadly inform the changes proposed in this NPRM.

The Department proposes to require that the regulated entity obtain this written verification documenting the business associate's deployment of the required technical safeguards at least once every 12 months. [623] Additionally, we propose that the verification include a written analysis of the business associate's relevant electronic information systems. [624] The written analysis would be required to be performed by a person with appropriate knowledge of and experience with generally accepted cybersecurity principles and methods for ensuring the confidentiality, integrity, and availability of ePHI to verify the business associate's compliance with each standard and implementation specification in 45 CFR 164.312 . [625] We also propose to require that the written verification be accompanied by a written certification by a person who has the authority to act on behalf of the business associate that the analysis has been performed and is accurate. [626] The proposal would permit the parties to determine the appropriate person to perform the analysis and how that person is engaged or compensated. This person may be a member of the covered entity's or business associate's workforce or an external party. This proposed new requirement that a regulated entity obtain written verification from its business associates that they have deployed technical safeguards combined with the existing requirement to obtain written satisfactory assurances that they safeguard ePHI, aligns with the Department's essential CPG for Vendor/Supplier Cybersecurity Requirements. [627] This CPG calls for regulated entities to identify, assess, and mitigate risks to ePHI used by or disclosed to business associates. [628] r. Section 164.308(b)(3)-Standard: Delegation To Business Associate Based on the OCR's investigations and enforcement experience, we believe that some regulated entities are not aware that they retain compliance responsibility for implementing requirements of the Security Rule, even when they have delegated the functions of designated security official to a business associate. Therefore, the Department proposes a new standard for delegation to a business associate at proposed 45 CFR 164.308(b)(3) . The proposed standard would clarify that a regulated entity may permit a business associate to serve as its designated security official. [629] However, a regulated entity that delegates actions, activities, or assessments required by the Security Rule to a business associate remains liable for compliance with all the applicable provisions of the Security Rule. [630] 4. Request for Comment The Department requests comment on the foregoing proposals, including any benefits, drawbacks, or unintended consequences. We also request comment on the following considerations in particular. For any proposed timeframe that a commenter believes is not appropriate, we request comment and explanation on a more appropriate timeframe. (printed page 957)

- 2) A statement based on detailed technical analysis that specifies the extent to which the security measures in the system or facility meet the security requirements. Certification is based on the results of the risk analysis performed. It does not necessarily imply a guarantee that the described system is impenetrable. It is an input to the security accreditation process. (AFR 700-10)
- 3) The technical evaluation of a system's security features, made as part of and in support of the approval/accreditation process, that establishes the extent to which a particular computer system's design and implementation meet a set of specified security requirements. (DOD 5200.28-STD)
- 4) The technical evaluation of an AIS's security features and other safeguards, made in support of the accreditation process, which establishes the extent to which a particular AIS design and implementation meet a set of specified security requirements. (DODD 5200.28)
- 5) Formal written assurance that, based on evaluation of security tests, the classified ADP system and its environment meet the security specifications outlined by the approved ADP security plan. (DOE 5637.1)
- 6) The technical evaluation, made as part of and in support of the accreditation process, that establishes the extent to which the design and implementation of a computer system or network meet prespecified

security requirements. (FIPS PUB 39; AR 380-380) - 7) The technical process evaluation, made as part of and in support of the accreditation process, whereby a procedure, program, system, component, or system is shown to be secure; i.e., that the security design specifications are correct and have been properly Implemented. Certification is performed by independent technical personnel according to an acceptable standard of proof such that the level of security protection is identified with regard to a procedure, program, system component, or system.

and insert the docket number, found in brackets in the heading of this document, into the Search box and follow the prompts and/or go to the Division of Dockets Management, 5630 Fishers Lane, Rm. 1061, Rockville, MD 20852. FOR FURTHER INFORMATION CONTACT: Ryan Cates, Office of Partnerships, Food and Drug Administration, Element Building, 12420 Parklawn Dr., Rockville, MD 20857, 301-796-5390, FAX: 301-827-3588, OP-ORA@fda.hhs.gov . SUPPLEMENTARY INFORMATION: I. Background on the New System and the Deleted System The FDA is establishing a new system of records referred to as the Commissioning of State and Local Officials (COSLO) system, to maintain records regarding State and local officials who apply to be commissioned by FDA. Under section 702(a)(1)(A) of the Federal Food, Drug, and Cosmetic Act (FD&C Act) (21 U.S.C. 372(a)(1)(A)), FDA can commission a health, food, or drug officer or employee of any State, territory, or political subdivision thereof (hereafter State and local officials) to conduct examinations and investigations for the purposes of the FD&C Act. In addition, FDA is deleting the SORN entitled FDA Credential Holder File, HHS/FDA/OC (System No. 09-10-0003). The records covered by that SORN (credential records for FDA employees and commissioned officials) will now be covered by this SORN for the COSLO system which contains records pertaining to commissioned officials, and by other existing personnel SORNs for records pertaining to FDA employees. Issued in Homeland Security Presidential Directive 12, Policy for a Common Identification Standard for Federal Employees and Contractors, FDA has completed the process of issuing Personal Identity Verification (PIV) badges to current employees and contractors, and will do the same for all new employees and contractors hired in the future. Records pertaining to those badges and background investigations are covered under HHS department-wide SORN No. 09-90-0777 entitled Facility and Resource Access Control Records System. Any additional records maintained to identify or manage FDA personnel designated to conduct examinations and inspections under the FD&C Act would be covered by HHS department-wide SORN No. 09-90-0018 entitled Personnel Records in Operating Offices or another personnel SORN.

According to Smart Cards and Mobile Device Authentication_ an Overview and Implementation, Summary: While mobile handheld devices provide productivity benefits, they also pose new risks associated with the information and network access capabilities they accumulate over time. User authentication safeguards against the risk of unauthorized use and access to a device's contents. This paper demonstrates how novel forms of smart cards can be implemented as a primary authentication method suitable for mobile devices. The methods used take advantage of interfaces built into most handheld devices, affording organizations the opportunity to extend smart card functionality easily to a segment of the computational infrastructure heretofore neglected.

Authentication processes resist replay attacks if it is impractical to successfully authenticate by recording or replaying previous authentication messages . Replay-resistant techniques include protocols that use nonces or challenges such as time synchronous or challenge- response one-time authenticators. NIST SP 800-63-3 provides guidance on digital identities. FURTHER DISCUSSION When insecure protocols are used for access to computing resources , an adversary may be able to capture login information and immediately reuse (replay) it for other purposes. It is important to use mechanisms that resist this technique. 104 NIST SP 800-171A, p. 32. 105 NIST SP 800-171 Rev. 2, p. 25. IA.L2-3.5.4 Replay-Resistant Authentication CMMC Assessment Guide Level 2 | Version 2.13 121 Example To protect your IT infrastructure, you understand that the methods for authentication must not be easily copied and re-sent to your systems by an adversary. You select Kerberos for authentication because of its built-in resistance to replay attacks. As a next step you upgrade all of your web applications to require Transport Layer Security (TLS), which also is replay-resistant. Your use of MFA to protect remote access also confers some replay resistance. Potential Assessment Considerations Are only anti-replay authentication mechanisms used [a]? KEY REFERENCES NIST SP 800-171 Rev. 2 3.5.4

From the NIST SP 800-172 Rev 3 Final Public Draft: 19 System components include mainframes, workstations, servers, input and output devices, network components, operating systems, virtual machines, applications, cyber-physical components (e.g., programmable logic controllers [PLC] or

medical devices), and mobile devices (e.g., smartphones and tablets). The security requirements for a nonfederal system processing, storing, or transmitting CUI that is associated with a critical program or a high value asset are conveyed to the nonfederal organization by the federal entity in a contract, grant, or other agreement. The implementation guidance associated with the security requirements is beyond the scope of this publication. Organizations have flexibility in the methods, techniques, technologies, and approaches used to satisfy the req

Agencies will also specify in the requirement the security and privacy controls necessary for contract performance. In accordance with paragraph (e) of the clause 52.239-YY, the controls specified by the agency will be based on the current version of the following documents at the time of contract award: NIST SP 800-53, ·Security and Privacy Controls for Information Systems and Organizations;· NIST SP 800-213 ·IOT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements;· NIST SP 800-161, ·Cybersecurity (printed page 68404) Supply Chain Risk Management Practices for Systems and Organizations;· and NIST SP 800-82, ·Guide to Industrial Control Systems Security.· Paragraph (e) also requires contractors to: (1) develop, review, and update, if appropriate, an SSP to support authorization of all applicable FIS, and (2) have contingency plans for all information technology systems, aligned to NIST SP 800-34, ·Contingency Planning Guide for Federal Information Systems.· The rule does not require a specific format for the SSP, but NIST SP 800-34 provides information on a template that contractors may choose to use. Contractors will be expected to provide a copy of the SSP, as well as make contingency plans available, to an agency upon request. In some situations, an information system may be designated as a high value asset by the agency. In accordance with paragraph (e) of the clause 52.239-YY, contractors will be subject to, as specified in the requirement, additional security and privacy controls for a high value asset, that could include the implementation of a high value asset overlay, immediate failover and/or recover plans, and complying with requisite cybersecurity assessments (e.g., contractor cooperation and allowing access). Additional considerations.

, NIST Special Publication (SP) 800-56C, Rev. 2. <https://doi.org/10.6028/NIST.SP.800-56Cr2> - [6] Dworkin MJ (2005) Recommendation for Block Cipher Modes of Operation: the CMAC Mode for Authentication. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-38B, Includes updates as of October 6, 2016. <https://doi.org/10.6028/NIST.SP.800-38B> - [7] National Institute of Standards and Technology (2008) The Keyed-Hash Message Authentication Code (HMAC). (U.S. Department of Commerce, Washington, DC), Federal Information Processing Standards Publication (FIPS) 198-1. <https://doi.org/10.6028/NIST.FIPS.198-1> - [8] Kelsey JM, Chang S-jH, Perlner RA (2016) SHA-3 Derived Functions: cSHAKE, KMAC, TupleHash, and ParallelHash. (National Institute of Standards and Technology, Gaithersburg, MD), NIST Special Publication (SP) 800-185. <https://doi.org/10.6028/NIST.SP.800-185> - [9] Goldreich O, Goldwasser S, Micali S (1986) How to construct pseudorandom functions, Journal of the ACM 33(4):210-217. <https://doi.org/10.1145/6490.6503> - [10] Adams C, Kramer G, Mister S, Zuccherato R (2004) On the Security of Key Derivation Functions. Information Security , Lecture Notes in Computer Science 3225 (Springer, Palo Alto, CA, USA), pp 134-145. http://doi.org/10.1007/978-3-540-30144-8_12

Several comments also question why records should be maintained for an additional 22 months after a product has been consumed. The comments state that 6 months is sufficient time to maintain records necessary for any traceback investigation related to food safety or security risks in the produce industry. One comment estimates that few, if any foods, would qualify as perishable as defined by FDA. The comment has identified only a few foods sold at retail that are ·not heat-treated, not frozen and not otherwise preserved in a manner so as to prevent the quality of the food from being adversely affected if held longer than 7 days under normal shipping and storage conditions,· namely bread, fish, and store prepared food. One comment supports the following revised definition of the term ·perishable food.· Perishable food means food that may have been thermally processed or otherwise preserved in a manner so as to prevent the quality of the foods from being adversely affected if held for 90 days or less under normal shipping and storage conditions. The comment agrees with FDA's decision to divide the food products subject to the record maintenance requirement into perishable and nonperishable groupings, but disagrees with the 7-day aspect of the proposed rule's definition of perishable. In addition, the comment does not believe that whether a food has been subjected to heat treatment or thermal processing should be a factor in differentiating between perishable and nonperishable food. The comment's members consider as ·perishable· those juice

products that have a shelflife of 90 days or less. If 90 days was substituted for 7 days in the definition of ‘perishable,’ this would result in retention of records for perishable products for at least 4 times their shelflife.

note 116, p. 541; ‘Start with Security: A Guide for Business,’ supra note 17. Back to Citation 250. See 45 CFR 164.312(a)(1) and (e)(1) ; PR.DS-1 and 2, ‘Framework for Improving Critical Infrastructure Cybersecurity,’ Cybersecurity Framework (CSF) Version 1.1, National Institute of Standards and Technology, U.S. Department of Commerce (Apr. 16, 2018), <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.04162018.pdf> ; PR.DS-01 and 02, ‘The NIST Cybersecurity Framework (CSF) 2.0,’ supra note 15. Back to Citation 251. ‘2021 HIMSS Healthcare Cybersecurity Survey,’ supra note 231, p. 23. Back to Citation 252. See ‘Hacking America’s Health Care: Assessing the Change Healthcare Cyber Attack and What’s Next,’ supra note 214 (According to CEO Andrew Witty, intruders used compromised credentials to remotely access an application used to enable remote access to desktops, which did not have MFA.). The Department’s investigation into the Change Healthcare breach is ongoing, and no conclusion has been reached with respect to its cause or whether Change Healthcare was in violation of the Security Rule. Back to Citation 253. 45 CFR 164.308(a)(4)(ii)(B) and 164.312(a)(1) ; ‘The NIST Cybersecurity Framework (CSF) 2.0,’ supra note 15; ‘Framework for Improving Critical Infrastructure Cybersecurity,’ supra note 250. Back to Citation 254. ‘RS.MA,’ ‘The NIST Cybersecurity Framework (CSF) 2.0,’ supra note 15. Back to Citation 255. ‘PR.IP-9,’ ‘Framework for Improving Critical Infrastructure Cybersecurity,’ supra note 250. Back to Citation 256. 45 CFR 164.304 (definition of ‘Security incident’). The definition of security incident includes both attempted and successful incidents. A successful incident is one in which a threat actor is able to, without authorization, access, use, disclose, modify, or destroy information or interfere with system operations in an information system. Back to Citation 257. See, e.g., ‘Montefiore Medical Center,’ supra note 248. Back to Citation 258. University of Texas M.D. Anderson Cancer Center v. U.S. Department of Health and Human Services, 985 F.3d 472, 478 (5th Cir. 2021). Back to Citation 259. Id. Back to Citation 260. Id. Back to Citation 261. ‘Sec. 1173(d)(2)(B) of Pub. L. 104-191 , 110 Stat. 2026 (Aug. 21, 1996) (codified at 42 U.S.C. 1320d-2). Back to Citation 262. 68 FR 8334 , 8336 (Feb. 20, 2003). Back to Citation 263. 42 U.S.C. 17931(a) ; 78 FR 5566 (Jan. 25, 2013). Back to Citation 264. 78 FR 5566 (Jan. 25, 2013). Back to Citation 265. Id. at 5591. Back to Citation 266. See 68 FR 8334 , 8341 (Feb. 20, 2003). Back to Citation 267. Id. at 8344. Back to Citation 268. See ‘2016-2017 HIPAA Audits Industry Report,’ supra

Analogous to the periodic table, the BF weakness taxonomies allow for the identification of as yet unencountered security weakness types, which would allow for the prediction of new kinds of vulnerabilities. The BF taxonomies and models also form the basis for defining secure coding principles, such as input/output check safety (e.g., injection safety), memory safety (e.g., buffer over/underflow safety or use-after-free safety), and data type safety (e.g., null pointer safety or subtype confusion safety). While the BF formal language is descriptive of weaknesses and vulnerabilities, the BF secure coding principles are prescriptive against them - they prevent bugs and faults that compromise code safety. The BF formalism supports a deeper understanding of vulnerabilities as chains of weaknesses that adhere to strict causal, propagational, and compositional rules and allows for backward bug identification from a failure. It enables a new range of research and development efforts for the creation of comprehensively labeled weakness and vulnerability datasets and the generation of formal vulnerability specifications and multidimensional vulnerability classifications. The BF also supports the development of new static or dynamic analysis and simulation or emulation algorithms [2], as well as AI models and capabilities to identify bugs and detect vulnerabilities. Given the formal specification of code and the BF definitions of weakness and vulnerability, formal methods could also be applied to detect vulnerabilities.

, as it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From 5 U.S.C. 552a(e)(4)(G) and (H) , as there is no necessity for such publication since the system of records

would be exempt from the underlying duties to provide notification about and access to information in the system and to make amendments and corrections to the information in the system. (E) From 5 U.S.C. 552a(e)(4)(I) , as to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. DLA, nevertheless, will continue to publish such a notice in broad generic terms as is its current practice. (2) System identifier and name. S500.10 (Specific exemption), Personnel Security Files. (i) Exemption. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (B) Therefore, portions of this system may be exempt pursuant to 5 U.S.C. 552a(k) (5) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), and (e)(1). (ii) Authority. 5 U.S.C. 552a(k)(5) . (iii) Reasons. (A) From 5 U.S.C. 552a(c)(3) and (d) , when access to accounting disclosures and access to or amendment of records would cause the identity of a confidential source to be revealed. Disclosure of the source's identity not only will result in the Department breaching the promise of confidentiality made to the source but it would impair the Department's future ability to compile investigatory material (printed page 14776) for the purpose of determining suitability, eligibility, or qualifications for Federal civilian employment, Federal contracts, or access to classified information. Unless sources may be assured that a promise of confidentiality will be honored, they will be less likely to provide information considered essential to the Department in making the required determinations. (B) From 5 U.S.C. 552a(e)(1) , as in the collection of information for investigatory purposes, it is not always possible to determine the relevance and necessity of particular information in the early stages of the investigation. In some cases, it is only after the information is evaluated in light of other information that its relevance and necessity becomes clear. Such information permits more informed decision making by the Department when making required suitability, eligibility, and qualification determinations.

(z) The Commander, U.S. Army Combat Readiness Center (formerly U.S. Army Safety Center), is authorized to act on requests for Army safety records. (aa) The Commander, U.S. Army Test and Evaluation Command (ATEC), is authorized to act on requests for the records of ATEC headquarters, its subordinate commands, units, and activities that relate to test and evaluation operations. (bb) The General Counsel, Army and Air Force Exchange Service, is authorized to act on requests for Army and Air Force Exchange Service records, under AR 60-20/AFR 147-14. (cc) The Commandant, United States Disciplinary Barracks (USDB) is authorized to act on records pertaining to USDB functional area responsibilities relating to the administration and confinement of individual military prisoners at the USDB. This includes, but is not limited to, all records pertaining to the treatment of military prisoners; investigation of prisoner misconduct; management, operation, and administration of the USDB confinement facility; and related programs which fall directly within the scope of the Commandant's functional area of command and control. (dd) The Commander, U.S. Army Community and Family Support Center (USACFSC) is authorized to act on requests for records pertaining to morale, welfare, recreation, and entertainment programs; community and family action programs; child development centers; non-appropriated funds issues, and private organizations on Army installations. (ee) The Commander, Military Surface Deployment and Distribution Command (formerly Military Traffic Management Command) is authorized to act on requests for records pertaining to military and commercial transportation and traffic management records. (ff) The Director, Installation Management Agency (IMA) is authorized to act on requests for all IMA records. (gg) Special Denial Authority's authority for time-event related records may be designated on a case-by-case basis. These will be published in the Federal Register . You may contact the Department of the Army, Freedom of Information and Privacy Office to obtain current information on special delegations. Appendix C to Part 505-Privacy Act Statement Format (a) Authority: The specific federal statute or Executive Order that authorizes collection of the requested information. (b) Principal Purpose(s): The principal purpose or purposes for which the information is to be used. (c) Routine Uses(s): Disclosure of the information outside DOD. (d) Disclosure: Whether providing the information is voluntary or mandatory and the effects on the individual if he or she chooses not to provide the requested information. (1) Example of a Privacy Act Statement: (i) Authority: Emergency Supplement Act of 2000; Public Law 106-246 ; 5 U.S.C. 3013 , Secretary of the Army; 10 U.S.C. 5013 , Secretary of the Navy; 10 U.S.C. 8013 , Secretary of the Air Force; Department of Defense Directive 8500.aa, Information Assurance (IA); and E.O. 9397 (SSN). (ii)

Principal Purpose(s):

It has been determined that Privacy Act rules for the Department of Defense are not significant rules. The rules do not (1) have an annual effect on the economy of \$100 million or more or adversely affect in a material way the economy; a sector of the economy; productivity; competition; jobs; the environment; public health or safety; or State, local, or tribal governments or communities; (2) create a serious inconsistency or otherwise interfere with an action taken or planned by another Agency; (3) materially alter the budgetary impact of entitlements, grants, user fees, or loan programs, or the rights and obligations of recipients thereof; or (4) raise novel legal or policy issues arising out of legal mandates, the President's priorities, or the principles set forth in this Executive order. C. Regulatory Flexibility It has been certified that Privacy Act rules for the Department of Defense do not have significant economic impact on a substantial number of small entities because they are concerned only with the administration of Privacy Act systems of records within the Department of Defense. D. Paperwork Reduction Act It has been certified that Privacy Act rules for the Department of Defense impose no information requirements beyond the Department of Defense and that the information collected within the Department of Defense is necessary and consistent with 5 U.S.C. 552a, known as the Privacy Act of 1974. E. Unfunded Mandates Reform Act It has been certified that the Privacy Act rulemaking for the Department of Defense does not involve a Federal mandate that may result in the expenditure by State, local and tribal governments, in the aggregate, or by the private sector, of \$100 million or more and that such rulemaking will not significantly or uniquely affect small governments. F. Executive Order 13132 (Federalism) It has been certified that the Privacy Act rules for the Department of Defense do not have federalism implications. The rules do not have substantial direct effects on the States, on the relationship between the National Government and the States, or on the distribution of power and responsibilities among the various levels of government. Robert Dickerson, Chief, U.S. Army Freedom of Information Act and Privacy Office. List of Subjects in 32 CFR Part 505 Privacy For reasons stated in the preamble the Department of the Army revises 32 CFR part 505 to read as follows: PART 505-ARMY PRIVACY ACT PROGRAM 505.1 General information. 505.2 General provisions. 505.3 Privacy Act systems of records. 505.4 Collecting personal information. 505.5 Individual access to personal information. 505.6 Amendment of records. 505.7 Disclosure of personal information to other agencies and third parties. 505.8 Training requirements. 505.9 Reporting requirements. 505.10 Use and establishment of exemptions. 505.11 Federal Register publishing requirements. 505.12 Privacy Act enforcement actions. 505.13 Computer Matching Agreement Program. 505.14 Recordkeeping requirements under the Privacy Act.

42 U.S.C. 1320d note); Sec. 4101 of ARRA, Public Law 111-5, 123 Stat. 467 (Feb. 17, 2009), amending sec. 1848 of the SSA (codified at 42 U.S.C. 1395w-4). Back to Citation 168. ·JaWanna Henry, et al., ·ONC Data Brief: Adoption of Electronic Health Record Systems among U.S. Non-Federal Acute Care Hospitals: 2008-2015,· The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, p. 1 (May 2016), https://www.healthit.gov/sites/default/files/briefs/2015_hospital_adoption_db_v17.pdf ; A Basic EHR collects information on patient demographics, problem lists, medication lists, and discharge summaries. It also includes computerized provider order entry for medications and enables clinicians to view certain reports. Id. at Appendix. Back to Citation 169. ··ONC Data Brief: Adoption of Electronic Health Record Systems among U.S. Non-Federal Acute Care Hospitals: 2008-2015,· supra note 168, p. 1; When used here, ·certified EHR Technology· means EHR technology that meets the technological capability, functionality, and security requirements adopted by the Department as certification criteria at 45 CFR part 170 .; see also ·Certified EHR Technology,· The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services (Sept. 6, 2013), <https://www.cms.gov/medicare/regulations-guidance/promoting-interoperability-programs/certified-ehr-technology> (·In order to efficiently capture and share patient data, health care providers need certified electronic health record (EHR) technology (CEHRT) that stores data in a structured format. Structured data allows health care providers to easily retrieve and transfer patient information and use the EHR in ways that can aid patient care.·). Back to Citation 170. · See sec. 4003(b) and 4004(b)(2) of Public Law 114-255, 130 Stat. 1165 (Dec. 13, 2016) (codified at 42 U.S.C. 300jj-11(c) and 42 U.S.C. 300jj-52). Back to Citation 171. ·Dustin Charles, et al., ·ONC Data Brief: Interoperability among U.S. Non-federal Acute Care Hospitals, 2014,· The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, p. 1 (Aug. 2015), https://www.healthit.gov/sites/default/files/briefs/onc_databrief25_interoperabilityv16final_081115.pdf . Back to

Citation 172. ·Meghan Hufstader Gabriel, et al., ·ONC Data Brief: Interoperable Exchange of Patient Health Information Among U.S. Hospitals: 2023,· The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services, p. 1 (May 2024), <https://www.healthit.gov/-sites/-default/-files/-2024-05/-Interoperable-Exchange-of-Patient-Health-Information-Among-U.S.-Hospitals-2023.pdf> . Back to Citation

In the context of surplus sales, it is the buyer's responsibility to adhere to export control laws and regulations. Therefore, the referenced paragraph has been deleted and a new paragraph (g) has been inserted to specify that disposition shall be in accordance with foreign and U.S. laws and regulations, including regulations involving export controls, host nation requirements, Final Governing Standards, and Government-to-Government agreements, and that the contractor's responsibility to comply with all applicable laws and regulations regarding export-controlled items exists independent of the information provided by the clause. The new language is consistent with the respondent's recommendation and current DFARS language at 252.204-7008. B. Inventory Schedules Comment: A respondent stated that the requirement at DFARS 245.602-1 for ·obtaining bills of material and reviewing recent purchases, and stock record entries· is not a part of the disposal process. The respondent commented that these duties require the plant clearance officer to have a working knowledge of every contract and that the process will drive up costs. DoD Response: The proposed language at 245.602-1 exists today in the current DFARS at 245.7201. The proposed rule moved 245.7201 to subpart 245.6, and renamed the subpart Reporting, Reutilization, and Disposal, to conform with the FAR; however, the language at DFARS 245.602-1 has been (printed page 52140) clarified to specify applicability only to termination inventory. Comment: In reference to DFARS 245.602-1, Inventory disposal schedules, a respondent asked for guidance on when a physical count was required and suggested ways of addressing efficiency. DoD response: Generally, the Government relies on quantity data provided by the contractor, and physical counts are usually required only if the plant clearance officer suspects data integrity issues; however, 245.602-1(2) has been clarified to specify potential methods of verifying quantities. Comment: A respondent was concerned about the requirement at 252.245-70XX(b)(1)(i)(A) and (B) to provide Federal Supply Codes (FSCs) and manufacturer name, because this information is not always available or known. DoD Response: The language at 252.245-7004(b)(1)(i)(A) and (B) has been modified in the final rule to require the FSC and manufacturer name only if the information is assigned and/or available. Comment: A respondent recommended that new definitions for the terms ·manufacturer name· and ·manufacturer part number· be added at the clause at 252.245-70XX. DoD response: These terms are used commonly; therefore, they have not been added to the definitions section of the clause. Comment: In reference to 252.245-70XX(b), Inventory disposal schedules, a respondent recommended that the supplier name and part number be required for all items in Federal condition code A1 being reported as excess on inventory schedules. DoD Response:

3. Explanation : This Standard specifies secure hash algorithms - SHA-1, SHA-224, SHA-256, SHA-384, SHA-512, SHA-512/224 and SHA-512/256 - for computing a condensed representation of electronic data (message). When a message of any length less than 2⁶⁴ bits (for SHA-1, SHA-224 and SHA-256) or less than 2¹²⁸ bits (for SHA-384, SHA-512, SHA-512/224 and SHA-512/256) is input to a hash algorithm, the result is an output called a message digest. The message digests range in length from 160 to 512 bits, depending on the algorithm. Secure hash algorithms are typically used with other cryptographic algorithms, such as digital signature algorithms and keyed-hash message authentication codes, or in the generation of random numbers (bits). The hash algorithms specified in this Standard are called secure because, for a given algorithm, it is computationally infeasible 1) to find a message that corresponds to a given message digest, or 2) to find two different messages that produce the same message digest. Any change to a message will, with a very high probability, result in a different message digest. This will result in a verification failure when the secure hash algorithm is used with a digital signature algorithm or a keyed-hash message authentication algorithm. This Standard specifies secure hash algorithms, SHA-1, SHA-224, SHA-256, SHA-384, SHA512, SHA-512/224 and SHA-512/256. All of the algorithms are iterative, one-way hash functions that can process a message to produce a condensed representation called a message digest . These algorithms enable the determination of a message's integrity: any change to the message will, with a very high probability, result in a different message digest. This property is useful in the generation and verification of digital signatures and message authentication codes, and in the generation of random numbers or bits.

. However, if an individual is denied any right, privilege, or benefit for which he would otherwise

be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (c)(7)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) All portions of this system of records which fall within the scope of 5 U.S.C. 552a(k)(2) may be exempt from the provisions of 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(2). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would place the subject of an investigation on notice that they are under investigation and provide them with significant information concerning the nature of the investigation, thus resulting in a serious impediment to law enforcement investigations. (B) From subsections (d) and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or (printed page 14794) impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because there is no necessity for such publication since the system of records will be exempt from the underlying duties to provide notification about and access to information in the system and to make amendments to and corrections of the information in the system.

ications and environments in which cryptographic modules may be employed. The security requirements cover areas related to the secure design and implementation of a cryptographic module. These areas include cryptographic module specification; cryptographic module interfaces; roles, services, and authentication; software/firmware security; operating environment; physical security; non-invasive security; sensitive security parameter management; self-tests; life-cycle assurance; and mitigation of other attacks. This standard supersedes FIPS 140-2, Security Requirements for Cryptographic Modules, in its entirety.

Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is a significant regulatory action and, therefore, was subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804. V. Regulatory Flexibility Act A final regulatory flexibility analysis has been prepared consistent with the Regulatory Flexibility Act, 5 U.S.C. 601, et seq., and is summarized as follows: The objective of this final rule is to implement in the Defense Federal Acquisition Regulation Supplement protection against risks to the supply chain affecting National Security Systems (NSS). The legal basis for this final rule is section 806 of the National Defense Authorization Act (NDAA) for Fiscal Year (FY) of 2011 (Pub. L. 111-383), as amended by section 806 of the NDAA for FY 2013 (Pub. L. 112-239). Congress has recognized a growing concern for risks to the supply chain for technology contracts supporting the Department of Defense (DoD). Congress has defined supply chain risk as the risk that an adversary may sabotage, maliciously introduce unwanted function, or otherwise subvert the design, integrity, manufacturing, production, distribution, installation, operation, or maintenance of a covered system so as to surveil, deny, disrupt, or otherwise degrade the function, use, or operation of such system (see 806(e)(4) of Pub. L. 111-383). This final rule calls for contractors providing information technology to DoD, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, to mitigate supply chain risk to the supplies and services being provided to the Government. It also enables agencies to exclude sources identified as having a

supply chain risk from consideration for award of a covered contract, in order to minimize the potential risk for supplies and services purchased by DoD to maliciously degrade the integrity and operation of sensitive information technology systems. Ultimately, DoD anticipates significant savings to taxpayers by reducing the risk of unsafe products entering our supply chain, which pose serious threats or risks to sensitive government information technology systems. No comments were received in response to the initial regulatory flexibility analysis.

Between the late 1980s and early 2000s, the internet hosted very basic websites that were mostly comprised of text (often just plain text but sometimes with simple formatting), images, and hyperlinks to other webpages. As a result, this era has since been dubbed the 'static' or 'read-only' web. Most websites were hosted by large organizations, government agencies, internet service providers, or tech-savvy users who were allotted a small portion of web storage from their internet service provider or other web-hosting provider to develop their own 'home page.' Websites eventually began to create more designs and styles via Hypertext Markup Language (HTML) tables, which allowed developers to change the format of their page. During this period, there were also some 'dynamic' pages on the web that used the Common Gateway Interface (CGI) to execute code on the server and generate a static webpage to be delivered to the end user. There were little to no client-side manipulatable websites. Online communications were done through email, bulletin boards, and forums, and there was almost no online shopping. Since there was not a lot of user interaction, organizations did not host massive amounts of user data. Web3 utilizes existing internet technologies that make up much of the current web architecture, such as Transmission Control Protocol/Internet Protocol (TCP/IP), remote procedure call (RPC), and Transport Layer Security (TLS). It can also use existing web services, servers, databases, and webpages to act as an interface. Web3 applications can be designed to interact with (as both input to and utilize output from) existing systems. Like blockchain systems and cryptocurrency systems, Web3 leverages well-known technologies, such as publickey cryptography, digital signatures, and cryptographic hashing algorithms. - [20] Department of Financial Protection & Innovation (2023) Crypto Scam Tracker.

(c) The USD(P) will, in accordance with DoD Directive 5111.1, 'Under Secretary of Defense for Policy (USD(P))' (available at <http://www.dtic.mil/whs/directives/corres/pdf/511101p.pdf>), advise the USD(I) and DSS on the foreign relations and international security aspects of FOCI, including FGI, foreign disclosures of U.S. classified information, exports of defense articles and technical data, security arrangements for DoD international programs, North Atlantic Treaty Organization security, and international agreements. (d) The USD(AT&L) will, in accordance with DoD Directive 5134.01, 'Under Secretary of Defense for Acquisition, Technology and Logistics (USD(AT&L))' (available at <http://www.dtic.mil/whs/directives/corres/pdf/513401p.pdf>): (1) Advise the USD(I) on the development and implementation of NISP policies, in accordance with DoD Instruction 5220.22. (2) Ensure that DoD Components establish and maintain a record capturing the current and legitimate need for access to classified information by contractors in the Defense Industrial Base. (3) Ensure that acquisition elements of DoD Components comply with the applicable provisions of DoD 5220.22-M. (e) The Director, DoD SAP Central Office (SAPCO) will, in accordance with DoD Directive 5205.07, 'Special Access Program (SAP) Policy' (available at <http://www.dtic.mil/whs/directives/corres/pdf/520507p.pdf>), notify DSS of the existence of SAP equities when DSS considers the acceptability of a contractor's FOCI action plan. In addition, the Director, DoD SAPCO, will develop procedures for the consideration of a NID when a contractor cleared under a Special Security Agreement (SSA) requires access to an unacknowledged Special Access Program (SAP). (f) The Heads of the Components will: (1) Oversee compliance by GCA personnel with applicable procedures identified in this subpart. (2) Designate in writing an individual who is authorized to make decisions and provide a coordinated GCA position on FOCI matters to DSS within timelines established in this part. (3) Submit proposed changes to DoD 5220.22-M, as deemed appropriate, to the OUSD(I) Security Directorate. § 117.56 Foreign ownership, control or influence (FOCI). (a) General. This section provides guidance for and establishes procedures concerning the initial or continued FCL eligibility of U.S. companies and U.S. contractors with foreign involvement; provides criteria for determining whether U.S. companies are under FOCI; prescribes responsibilities in FOCI matters; and outlines security measures that DSS may consider to mitigate or negate the effects of FOCI to an acceptable level. As stated in DoD 5220.22-M, and in accordance with E.O. 12829 : (1) The Secretary of Defense serves as the Executive Agent for inspecting and monitoring contractors who require or will require access to, or who store or will store classified information.

FAR 4.403 is replaced with new content that provides instructions on the implementation of the CUI Program. The added language identifies the contracting officer's role in receiving and incorporating the SF XXX in solicitations and contracts and the contracting officer's responsibilities during contract administration. A new provision at FAR 52.204-WW, Notice of Controlled Unclassified Information Requirements, and new clauses at FAR 52.204-XX, Controlled Unclassified Information, and 52.204-YY, Identifying and Reporting Information That Is Potentially Controlled Unclassified Information, are also prescribed. The changes for FAR 4.403 include the following: Existing FAR 4.403 has been renumbered as FAR 4.402-2. The clause at FAR 4.404 was moved to a new FAR 4.402-3. FAR 4.403-1 adds definitions for ·CUI Basic,· ·CUI categories,· ·CUI Specified,· ·handling,· ·lawful Government purpose,· ·limited dissemination control,· and ·on behalf of an agency.· FAR 4.403-2 provides information on E.O. 13556 including that the E.O. establishes NARA as the executive agent for the CUI Program. FAR 4.403-3 gives the applicability of the SF XXX and the new FAR clauses 52.204-XX and 52.204-YY. FAR 4.403-4 outlines the CUI policy and requires that CUI involved in performance of a contract shall be identified on a SF XXX and incorporated into the contract. Unmarked or mismarked CUI is not considered a CUI incident unless the mismarking or lack of marking has resulted in the mishandling or improper dissemination of the information. Offerors are requested and contractors are required to notify the Government within an 8 hour timeframe if they discover or suspect information is CUI, but that CUI is not listed on an SF XXX or is not marked or properly marked. FAR 4.403-5 adds the usage of the SF XXX. The SF XXX itself has detailed instructions. FAR 4.403-6 provides that the agency point of contact to whom the contractor reports an incident is found in the SF XXX at Part C, Section IV. When the SF XXX is not used in a contract, the point of contact is identified in FAR 52.204-YY(b). FAR 4.403-6 explains that the SF XXX should list any special incident reporting requirements for CUI Specified. FAR 4.403-6 also adds that the contracting officer shall provide instructions to the contractor for submitting the system images, in accordance with agency procedures. FAR 4.403-6 also explains that the contractor is required to hold the system images for 90 days unless the Government declines interest.

Professional Backgrounds, Knowledge, Skills, and Development Activities Professional Backgrounds, Knowledge, Skills, and Development Activities There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST.

Two types of requirements are delineated for secure processing: (1) specific security feature requirements and; (2) assurance requirements. The latter enable evaluation personnel to determine if the required features are present and functioning as intended. The Orange Book forms the basis upon which the National Computer Security Center (NCSC) conducts its commercial computer security evaluation process. This process is focused on commercially produced and supported general-purpose operating system products that meet the needs of government departments and agencies. The evaluation is aimed at off-the-shelf products and is completely separate from any considerations of overall system performance, potential applications, or processing environments. The evaluation can provide a key input to a computer system security approval /accreditation . However, it does not constitute a complete computer system security study. A complete study must consider additional factors dealing with the system in its unique environment, such as its proposed security mode of operation, specific users, applications, data sensitivity, physical and personnel security, administrative security and communications security The Orange Book and Red Book criteria do not address all of the security concerns that arise when one actually deploys a system, whether it consists of a single computer or is composed of multiple computer and network products from different vendors. Procedural, physical and personnel safeguards enter into overall system security, and these are only partially addressed by these two documents. System security requires a thorough analysis of the system in question, taking into account not only the ratings of products that might be used to build the system, but also the threats directed against the system. Based on this analysis a security architecture can then be proposed and developed.

The Department of the Army will submit reports, consistent with the requirements of DOD 5400.11-R, OMB Circular A-130, and as otherwise directed by the Defense Privacy Office. Contact the DA FOIA/P Office for further guidance regarding reporting requirements. §505.10 Use and establishment of

exemptions. (a) Three types of exemptions. (1) There are three types of exemptions applicable to an individual's right to access permitted by the Privacy Act. They are the Special, General, and Specific exemptions. (2) Special exemption (d)(5)-Relieves systems of records from the access provision of the Privacy Act only. This exemption applies to information compiled in reasonable anticipation of a civil action or proceeding. (3) General exemption (j)(2)-Relieves systems of records from most requirements of the Act. Only Army activities actually engaged in the enforcement of criminal laws as their primary function may claim this exemption. (4) Specific exemptions (k)(1)-(k)(7)-Relieves systems of records from only a few provisions of the Act. (5) To find out if an exemption is available for a particular record, refer to the applicable system of records notices. System of records notices will state which exemptions apply to a particular type of record. System of records notices that are applicable to the Army are contained in DA Pam 25-51 (available at the Army Publishing Directorate Web site <http://www.usapa.army.mil/>), the Defense Privacy Office's Web site <http://www.defenselink.mil/privacy/>), or in this section). Some of the system of records notices apply only to the Army and the DOD and some notices are applicable government-wide. (6) Descriptions of current exemptions are listed in detail at appendix C of this part. (b) Exemption procedures. (1) For the General and Specific exemptions to be applicable to the (printed page 24507) Army, the Secretary of the Army must promulgate exemption rules to implement them. This requirement is not applicable to the one Special exemption which is self-executing. Once an exemption is made applicable to the Army through the exemption rules, it will be listed in the applicable system of records notices to give notice of which specific types of records the exemption applies to. When a system manager seeks to have an exemption applied to a certain Privacy Act system of records that is not currently provided for by an existing system of records notice, the following information will be furnished to the DA FOIA/P Office: (i) Applicable system of records notice; (ii) Exemption sought; and (iii) Justification. (2) After appropriate staffing and approval by the Secretary of the Army and the Defense Privacy Office, it will be published in the Federal Register as a proposed rule, followed by a final rule 60 days later. No exemption may be invoked until these steps have been completed. § 505.11 Federal Register publishing requirements. (a) The Federal Register.

(1) When a member of the public complies with the procedures in this part and DoD Component supplementing regulations for obtaining DoD records, and the request is received by the official designated to respond, the DoD Component shall endeavor to provide a final response determination within the statutory 20 working days (5 U.S.C. 552(a)(6)(A)(i)). If unusual circumstances prevent a final response determination within the statutory time period, the Component shall advise the requester of this in writing, and provide a new completion date, which shall be not later than an additional 10 working days. If the Component needs more than this 10-day extension, it will provide the requester an opportunity to narrow the scope of the request, or arrange for an alternative timeframe. (i) Unusual circumstances are: (A) The responsive documents are located at a facility geographically separated from the office processing the FOIA request. (B) The responsive documents are voluminous. (printed page 71850) (C) One or more other outside agencies have a substantial interest in either the determination or the subject matter of the request, requiring the DoD Component processing the request to consult with the other agencies. This would include the submitter notice process (§ 286.18(d)(1)(i)(A)). (ii) A final response determination is notification to the requester that the records are released, or that the records cannot be provided for one or more of the reasons in § 286.13. Interim responses acknowledging receipt of the request are encouraged, as are negotiations with the requester concerning the scope of the request, the response timeframe, and the fee agreement. Such communications do not, however, constitute a final response determination. (2) If a request fails to meet the minimum requirements of this part, the DoD Component shall inform the requester how to perfect or correct the request. The statutory 20-working day time limit applies upon receipt of a perfected or correct FOIA. (d) Use of exemptions. It is DoD policy (32 CFR part 285) to make records publicly available, unless the record or portions thereof qualify for withholding under one or more of the 9 exemptions. (e) Waiver of exemptions. Records released under the authority of this part are considered to be in the public domain. The disclosure of exempt records without authorization by the appropriate DoD official is not considered a FOIA release. Such a release does not waive the Department of Defense's authority to assert FOIA exemptions to withhold the same records in response to a FOIA request. Also, while authority may exist to disclose records to individuals in their official capacity, the provisions of this part apply if the same individual seeks the records in a private or personal capacity. (f) Creating a record.

Historically, regulated entities relied on combinations of usernames and passwords to identify users and authenticate users to the system. We recognize that such combinations are insufficient to secure sensitive information and that more sophisticated mechanisms for doing so have been developed. As a best practice for managing cyber threats, most cybersecurity frameworks, including those discussed above, recommend that organizations adopt solutions that rely on multiple factors to identify and authenticate users. For example, the HHS 405(d) Program's 'Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients' [363] recommends a layered approach to cyber defense (i.e., if a first layer is breached, a second exists to prevent a complete breach). [364] It further provides that MFA as a source of identity and access security control is an important means to control access to infrastructure and conduct proper change management control. [365] The Department's CPGs [366] identify MFA as an essential goal and a critical, additional layer of security for the protection of assets and accounts that are directly accessible from the internet. [367] The Department has also explained in guidance that weak authentication processes leave organizations vulnerable to intrusion, while effective authentication ensures that only authorized entities may access information systems and data. [368] Additionally, CISA has issued recommendations for implementing MFA, specifically MFA solutions that are phishing resistant to protect against disclosures of authentication data to a bad actor. [369]

b. Proposal The Department proposes to define the term 'Multi-factor authentication' to provide regulated entities with a specific level of authentication for accessing relevant electronic information systems. [370] Regulated entities would be required to apply this proposed definition when implementing the proposed rule's specific requirements for authenticating users' identities through verification of at least two of three categories of factors of information about the user. The proposed categories would be: Information known by the user, including but not limited to a password or personal identification number (PIN). Item possessed by the user, including but not limited to a token or a smart identification card. Personal characteristic of the user, including but not limited to fingerprint, facial recognition, gait, typing cadence, or other biometric or behavioral characteristics. MFA relies on the user presenting at least two factors. Authentication that relies on multiple instances of the same factor, such as requiring a password and PIN, is not MFA because both factors are 'something you know.' [371] For example, where MFA is deployed, users could seek access by entering a password. However, without the entry of at least a second factor such as a token [372]

. However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of the information, the individual will be provided access to the information exempt to the extent that disclosure would reveal the identity of a confidential source. Note 1 to paragraph (e)(6)(i)(B). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k) (2) from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (H) and (I), and (f). (ii) Authority. 5 U.S.C. 552a(j)(2) and (k)(2) . (iii) Reasons. (A) From subsection (c)(3) because the release of accounting of disclosure would inform a subject that he or she is under investigation. This information would provide considerable advantage to the subject in providing him or her with knowledge concerning the nature of the investigation and the coordinated investigative efforts and techniques employed by the cooperating agencies. This would greatly impede the Air Force IG's criminal law enforcement. (B) From subsection (c)(4) and (d), because notification would alert a subject to the fact that an open investigation on that individual is taking place, and might weaken the ongoing investigation, reveal investigative techniques, and place confidential informants in jeopardy. (C) From subsection (e)(1) because the nature of the criminal and/or civil investigative function creates unique problems in prescribing a specific parameter in a particular case with respect to what information is relevant or necessary. Also, information may be received which may relate to a case under the investigative jurisdiction of another agency. The maintenance of this information may be necessary to provide leads for appropriate law enforcement purposes and to establish patterns of activity that may relate to the jurisdiction of other cooperating agencies. (D) From subsection (e)(2) because collecting information to the fullest extent possible directly from the subject individual may or may not be practical in a criminal and/or civil investigation. (E) From subsection (e)(3) because supplying an individual with a form containing a Privacy Act Statement would tend to inhibit cooperation by many individuals involved in a criminal and/or civil investigation. The effect would be somewhat adverse to established investigative methods and techniques. (F) From subsections (e)(4)(G), (H), and (I) because this system of records is exempt

from the access provisions of subsection (d) and (f).

(A) Granting individuals access to portions of these records pertaining to or consisting of, but not limited to, disciplinary reports, criminal investigations, and related statements of witnesses, and such other related matter in conjunction with the enforcement of criminal laws, could interfere with the orderly investigations, with the orderly administration of justice, and possibly enable suspects to avoid detection or apprehension. Disclosure of this information could result in the concealment, destruction, or fabrication of evidence, and jeopardize the safety and well-being of informants, witnesses and their families, and law enforcement personnel and their families. Disclosure of this information could also reveal and render ineffectual investigative techniques, sources, and methods used by these components and could result in the invasion of the privacy of individuals only incidentally related to an investigation. The exemption of the individual's right of access to portions of these records, and the reasons therefore, necessitate the exemption of this system of records from the requirement of the other cited provisions. (B) [Reserved] (5) System identifier and name. N01754-3, Navy Child Development Services Program. (i) Exemption. (A) Investigatory material compiled for law enforcement purposes may be exempt pursuant to 5 U.S.C. 552a(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. (B) Portions of this system of records are exempt from the following subsections of the Privacy Act: (c)(3) and (d). (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. (A) Exemption is needed in order to encourage persons having knowledge of abusive or neglectful acts toward children to report such information, and to protect such sources from embarrassment or recrimination, as well as to protect their right to privacy. It is essential that the identities of all individuals who furnish information under an express promise of confidentiality be protected. Additionally, granting individuals access to information relating to criminal and civil law enforcement, as well as the release of certain disclosure accountings, could interfere with ongoing investigations and the orderly administration of justice, in that it could result in the concealment, alteration, destruction, or fabrication of information; could hamper the identification of offenders and the disposition of charges; and could jeopardize the safety and well being of parents and their children. (B) [Reserved] (6) System identifier and name. N03834-1, Special Intelligence Personnel Access File. (i) Exemption. (A) Information specifically authorized to be classified under E.O. 12958

The CMMC Program is intended to: (1) align cybersecurity requirements to the sensitivity of unclassified information to be protected, and (2) add a certification element, where appropriate, to verify implementation of cybersecurity requirements. As part of the program, DoD also intends to provide supporting resources and training to defense contractors to help support companies who are working to achieve the required CMMC Status. The CMMC Program provides for assessment at three levels: basic safeguarding of FCI at CMMC Level 1, broad protection of CUI at CMMC Level 2, and enhanced protection of CUI against risk from Advanced Persistent Threats (APTs) at CMMC Level 3. The CMMC Program is designed to provide increased assurance to the Department that a defense contractor can adequately protect FCI and CUI in accordance with prescribed security requirements, accounting for information flow down to its subcontractors in a multi-tier supply chain. The CMMC Program addresses DoD's need to protect FCI and CUI during the acquisition and sustainment of products (printed page 83173) and services from the DIB. This effort is instrumental in establishing cybersecurity as a foundation for future DoD acquisition. Although DoD contract requirements to provide adequate security for covered defense information (reflected in DFARS clause 252.204-7012) predate CMMC by many years, a certification requirement for the handling of CUI to assess a contractor or subcontractor's compliance of those required information security controls is new with the CMMC Program. Findings from DoD Inspector General report [36] indicate that DoD contractors did not consistently implement mandated system security requirements for safeguarding CUI and recommended that DoD take steps to assess a contractor's ability to protect this information. The report emphasizes that malicious actors can exploit the vulnerabilities of contractors' networks and systems and exfiltrate information related to some of the Nation's most valuable advanced defense technologies. Currently, the FAR and DFARS prescribe contract clauses intended to protect FCI and CUI. Specifically, the clause at FAR 52.204-21, Basic Safeguarding of Covered Contractor Information Systems , is prescribed at FAR 4.1903 for use in Government solicitations and contracts when the contractor or a subcontractor at any tier may have FCI residing in or transiting through its information system(s). This clause requires contractors and

subcontractors to implement basic safeguarding requirements and procedures to protect FCI being processed, stored, or transmitted on contractor information systems. In addition, DFARS clause 252.204-7012, Safeguarding Covered Defense Information and Cyber Incident Reporting

This rule applies to contractors providing the Government with information technology that qualifies as a covered system or covered item of supply. This includes purchases of commercial items, including commercial off-the-shelf items, and contracts not greater than the simplified acquisition threshold. While it is not possible to estimate the number of small businesses impacted, DoD does not expect this final rule to have a significant economic impact on a substantial number of contractors, since (1) the rule applies only when acquiring information technology that is part of a covered system or in support of a covered system and (2) the authority provided by the rule is expected to be invoked very infrequently. This rule does not require any specific reporting, recordkeeping or compliance requirements. No significant economic impact on small businesses is anticipated; however, the final rule does have a modified applicability for the provision and clause created by the rule. Instead of being prescribed for all information technology acquisitions the provision and clause will only apply to acquisitions for information technology that is a covered system or covered item of supply. This will significantly reduce the number of acquisitions to which the provision and clause will apply.

VI. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). List of Subjects in 48 CFR Parts 202 , 208 , 212 , 213 , 214 , 215 , 233 , 239 , 244 , and 252 Government procurement

Jennifer L. Hawes, Editor, Defense Acquisition Regulations System. Accordingly, DoD adopts as final the interim rule published at 78 FR 69268 on November 18, 2013, with the following changes:

1. The authority citation for 48 CFR parts 202 , 208 , 212 , 213 , 214 , 215 , 239 , 244 , and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1 .

PART 202-DEFINITIONS OF WORDS AND TERMS

2. Amend section 202.101 by adding, in alphabetical order, a definition for ·Information technology· to read as follows: 202.101 Definitions. * * * * *

Information technology (see 40 U.S.C. 11101(6)) means, in lieu of the definition at FAR 2.1, any equipment, or interconnected system(s) or subsystem(s) of equipment, that is used in the automatic acquisition, storage, analysis, evaluation, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information by the agency. (1) For purposes of this definition, equipment is used by an agency if the equipment is used by the agency directly or is used by a contractor under (printed page 67251) a contract with the agency that requires· (i) Its use; or (ii) To a significant extent, its use in the performance of a service or the furnishing of a product.

Section 170.1 addresses the purpose of this rule. It describes the CMMC Program and establishes policy for requiring the protection of FCI and CUI that is processed, stored, or transmitted on defense contractor and subcontractor information systems. The security standards utilized in the CMMC Program are from the FAR clause 52.204-21; DFARS clause 252.204-7012 that implements NIST SP 800-171 R2; and selected requirements from the NIST SP 800-172 Feb2021, as applicable. The purpose of the CMMC Program is for contractors and subcontractors to demonstrate that FCI and CUI being processed, stored, or transmitted is adequately safeguarded through the methodology provided in the rule.

Section 170.2-Incorporation by Reference Section 170.2 addresses the standards and guidelines that are incorporated by reference. The Director of the Federal Register under 5 U.S.C. 552(a) and 1 CFR part 51 approves any materials that are incorporated by reference. Materials that are incorporated by reference in this rule are reasonably available. Information on how to access the documents is detailed in §170.2. Materials that are incorporated by reference in this rule are from the NIST (see §170.2(a)), the Committee on National Security Systems (see §170.2(b)), and the International Organization for Standardization/International Electrotechnical Commission (ISO/IEC) (see §170.2(c)) which may require payment of a fee. Note: While the ISO/IEC standards are issued jointly, they are available from the ISO Secretariat (see §170.2(c)). The American National Standards Institute (ANSI) IBR Portal provides access to standards that have been incorporated by reference in the U.S. Code of Federal Regulations at <https://ibr.ansi.org> . These standards incorporated by the U.S. government in rulemakings are offered at no cost in ·read only· format and are presented for online reading. There are no print or download options. All users will be required to install the FileOpen plug-in and accept an online end user license agreement prior to accessing any standards. The materials that are incorporated by reference are summarized below.

(ii) The foreign government is currently exercising, or could prospectively exercise, that power,

whether directly or indirectly, such as: (A) Through ownership of the U.S. entity's securities, by contractual arrangements, or other means, or; (B) By the ability to control or influence the election or appointment of one or more members to the entity's governing board. (2) When the CSA has determined that an entity is under FOCI, the primary consideration will be the protection of classified information. The CSA will take whatever action is necessary to protect classified information, in coordination with other affected agencies as appropriate. (3) A U.S. entity that is in process for an entity eligibility determination for access to classified information and subsequently determined to be under FOCI is ineligible for access to classified information unless and until effective security measures have been put in place to negate or mitigate FOCI to the satisfaction of the CSA. (4) When a contractor determined to be under FOCI is negotiating an acceptable FOCI mitigation or negation measure in good faith, an existing entity eligibility determination may continue in effect so long as there is no indication that classified information is at risk of compromise in consultation with the applicable GCA. The applicable CSA may decide that circumstances involving the FOCI are such that the entity eligibility determination will be invalidated until implementation of an acceptable FOCI mitigation plan. (5) An existing entity eligibility determination will be invalidated if the contractor is unable or unwilling to negotiate and implement an acceptable FOCI mitigation or negation measure. An existing entity eligibility determination will be revoked if security measures cannot be taken to remove the possibility of unauthorized access to classified information or adverse effect on performance of classified contracts. (6) Changed conditions, such as a change in ownership, indebtedness, or a foreign intelligence threat, may justify certain adjustments to the security terms under which an entity is operating or, alternatively, that a different FOCI mitigation or negation method be employed. If a changed condition is of sufficient significance, it might also result in a determination that a contractor is no longer considered to be under FOCI, or, conversely, that a contractor is no longer eligible for access to classified information. (7) The USG reserves the right, and has the obligation, to impose any security method, safeguard, or restriction (including denial, termination or revocation of an entity eligibility determination) it believes necessary to ensure that unauthorized access to classified information is effectively precluded and performance of classified contracts is not adversely affected.

DISCUSSION Integrated analysis of audit records requires that the analysis of information NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 generated by scanning, monitoring, or other data collection activities is integrated 894

The National Institute of Standards and Technology (NIST) and the National Security Agency (NSA) initiated a joint project in Computer Network Security in 1984. The project was based on the recognition that a comprehensive set of security mechanisms is needed to provide cost effective access control to data in geographically distributed computer networks. While the detailed security mechanisms can differ between the classified and unclassified communities requiring security, both communities benefit when commercial computer networks are developed with a common security architecture. The NSA initiated the Secure Data Network System (SDNS) program in 1986 as a result, at least partially, of this joint project. - (1) Data Integrity, - (2) Data Confidentiality, - (3) Data Origination Authentication, and - (4) Access Control. | Index | Service Element | Status | Support | Support |

|-----|-----|-----|-----|-----| |
TOSEO | Confidentiality | 0.1 | Y | N | | TOSEI | Connection Confidentiality | TOSEO:m | Y | N | |
T0SE2 T0SE3 | Connectionless Confidentiality Integrity | - 0.1 | Y | N | | T0SE4 | Connection
Integrity w Recovery | - | | | T0SE5 | Connection Integrity wo Recovery | - | | | T0SE6 |
Connectionless Integrity | T0SE3:m | Y | N | | T0SE7 | Data Origination Authentication | m | Y | N |
| T0SE8 | Access Control | o | Y | N |

The identification of information processed on an information system is essential to the proper selection of security controls and ensuring the confidentiality, integrity, and availability of the system and its information. The National Institute of Standards and Technology (NIST) Special Publication (SP) 800-60 has been developed to assist Federal government agencies to categorize information and information systems. Security categorization provides a vital step in integrating security into the government agency's business and information technology management functions and establishes the foundation for security standardization amongst their information systems. Security categorization starts with the identification of what information supports which government lines of business, as defined by the Federal Enterprise Architecture (FEA). Subsequent steps focus on the

evaluation of the need for security in terms of confidentiality, integrity, and availability. The result is strong linkage between missions, information, and information systems with cost effective information security. Federal agencies are heavily dependent upon information and information systems to successfully conduct critical missions. With an increasing reliability on and growing complexity of information systems as well as a constantly changing risk environment, information security has become a mission-essential function. This function must be conducted in a manner that reduces the risks to the information entrusted to the agency, its overall mission, and its ability to do business and to serve the American public. In the end, information security, as a function, becomes a business enabler through diligent and effective management of risk to information confidentiality, integrity, and availability.

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 Organizations can create rules based on specified attributes and the authorizations 579

, 531 U.S. 159 (2001).) The agency has considered the relevant provisions of the Bioterrorism Act, the comments submitted on this issue, FDA's responsibilities in implementing the Bioterrorism Act, and the law interpreting the Commerce Clause of the Constitution (Article I, section 8). Based on these considerations, FDA is retaining § 1.326(b) as proposed, with the result that all persons that manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States (unless otherwise exempt) must establish and maintain records, even if food from the facility does not enter interstate commerce. The plain language of new section 414 of the FD&C Act does not exclude a facility from recordkeeping because food from such facility does not enter interstate commerce. Notably, sections 301 and 304 (21 U.S.C. 331 and 334) of the FD&C Act demonstrate that Congress has included a specific interstate commerce nexus (e.g., has explicitly required interstate commerce) in the provisions of the FD&C Act when that is its intent. Accordingly, it is reasonable to interpret the Bioterrorism Act as not limiting recordkeeping only to those persons with a direct connection to interstate commerce. Congress's power to legislate under the Commerce Clause is very broad. We acknowledge that such power is not without limits, see *United States v. Lopez*, 514 U.S. 549, 567 (1995); *U.S. v. Morrison*, 529 U.S. 598, 618 (2000), but these limits have to be construed in light of relevant and enduring precedents. In particular, in *Lopez*, supra, the Supreme Court acknowledged the continuing vitality of *Wickard v. Filburn*, 317 U.S. 111 (1942), noting that: *** although *Filburn's* own contribution to the demand for wheat may have been trivial by itself, that was not enough to remove him from the scope of federal regulation where, as here, his contribution, taken together with that of many others similarly situated, is far from trivial.*** (*Lopez*, 514 U.S. at 556.) This principle applies squarely to the recordkeeping provision of the Bioterrorism Act. Accordingly, given the collective impact on commerce of intrastate manufacturing, processing, packing, transporting, distributing, receiving, or holding of food in the United States, FDA has concluded that the requirement to establish and maintain records should apply regardless of whether the food enters interstate commerce. Thus, FDA is retaining § 1.326(b) as proposed. See also response to comment 82 below for an expanded discussion of the collective impact on commerce of intrastate transportation of food. This is consistent with section 709 of the FD&C Act (21 U.S.C. 379a

The CMMC rule made no change to the FAR cost allowability or cost accounting standards. The 7% discount rate is not a discount for organizations; it is a part of a formula used in the regulatory impact analysis (RIA) calculations. When calculating 20 years in the future, a discount rate is used to determine the net present value of money. The cost estimate represents derived estimates based on internal expertise and public feedback in accordance with OMB Circular A-4: Regulatory Impact Analysis: A Primer. Step 7 in the manual explains discount rates. As written, this rule amply provides for the flexibility sought by the (printed page 83198) commenter. Rule section § 170.21 specifically addresses the flexibility to have a Plan of Action and Milestones (POA&M) to delay meeting certain requirements subject to CMMC assessment for up to 180 days. In addition, DFARS clause 252.204-7012 already permits contractors to request DoD CIO permission to utilize alternative security measures to those prescribed by NIST SP 800-171. If an OSC previously received a favorable adjudication from the DoD CIO for an alternative security measure, the DoD CIO adjudication must be included in the system security plan to receive consideration during an assessment. Implemented security measures adjudicated by the DoD CIO as equally effective are assessed as MET if there have been no changes in the environment. 3. CMMC Model. Some commenters claimed that the requirement for all subcontractors of Level 3 prime contractors to be at least Level 2 certified, regardless of

what work they do, will generate more demand for Level 2 assessments than the Department is anticipating. Since much of DoD's contract dollars flow through a relatively small number of companies, it is likely those companies will have at least one CMMC Level 3 project. The result would be Level 2 certification requirements being flowed down to nearly the entirety of the DIB. Some commenters believed this to be an unintended consequence of implementing the enhanced protection of CMMC Level 3. DoD Response: It is possible the commenters misunderstood § 170.23 Application to subcontractors in the rule. § 170.23(a)(4) states: "If a subcontractor will process, store, or transmit CUI in performance of the subcontract and the associated prime contractor has a requirement for the CMMC Status of Level 3 (DIBCAC), then the CMMC Status of Level 2 (C3PAO) is the minimum requirement for the subcontractor." The commenter's phrase "regardless of what work they do" does not acknowledge the fact that the Level 2 certification assessment is required for subcontractors who process, store, or transmit CUI.

To request more information on this proposed information collection or to obtain a copy of the proposal and associated collection instruments, please write to the Defense Acquisition Regulations System, Attn: Ms. Amy G. Williams, OUSD(A&S)DPC/DARS, Room 3B941, 3060 Defense Pentagon, Washington, DC 20301-3060, or email osd.dfars@mail.mil. Include DFARS Case 2019-D002 in the subject line of the message. List of Subjects in 48 CFR Parts 204, 232, and 252 Government procurement Jennifer Lee Hawes, Regulatory Control Officer, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204, 232, and 252 are proposed to be amended as follows: 1. The authority citation for 48 CFR parts 204, 232, and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1. PART 204-ADMINISTRATIVE MATTERS 2. Amend section 204.1202 by: a. Revising the section heading; b. Redesignating paragraph (2)(xiii) as (2)(xiv); and c. Adding a new paragraph (2)(xiii). The revision and addition read as follows: 204.1202 Solicitation provision and contract clause. * * * * * (2) * * * (xiii) 252.232-70XX, Performance-Based Payments-Representation. * * * * * PART 232-CONTRACT FINANCING 3. In section 232.1001, revise paragraph (a) to read as follows: 232.1001 Policy. (a) In accordance with 10 U.S.C. 2307(b)(2), performance-based payments shall not be conditioned upon costs incurred in contract performance, but on the achievement of performance outcomes. Private sector companies, including nontraditional defense contractors, are eligible for performance-based payments, consistent with best commercial practices. * * * * * 4. Revise section 232.1003-70 to read as follows: 232.1003-70 Criteria for use. In accordance with 10 U.S.C. 2307(b), the output of a contractor's accounting system shall be in compliance with Generally Accepted Accounting Principles, as evidenced by audited financial statements, in order to receive performance-based payments. 10 U.S.C. 2307 does not grant the Defense Contract Audit Agency the authority to audit compliance with Generally Accepted Accounting Principles. 5. Amend section 232.1005-70 by: a. Designating the introductory text as paragraph (a); (printed page 18224) b. Redesignating paragraphs (a) and (b) as paragraphs (a)(1) and (2), respectively; and c. Adding a new paragraph (b). The addition reads as follows: 232.1003-70 Criteria for use. * * * * * (b) Use the provision at 252.232-70XX, Performance-Based Payments-Representation, in solicitations where the resulting contract may include performance-based payments. PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 6. Amend section 252.204-7007 by: a. Removing the provision date of (APR 2018) and adding (DATE) in its place; and b. Adding paragraph (d)(2)(vi) to read as follows: 252.204-7007 Alternate A, Annual Representations and Certifications. * * * * * (d) * * * (2) * * * (vi) 252.232-70XX, Performance-Based Payments-Representation. * * * * * 7. Amend section 252.232-7012 by: a. In the clause introductory text, removing 232.1005-70(a) and adding 232.1005-70(a)(1) in its place; b.

Note 1 to paragraph (c)(13)(i)(A). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. (B) All portions of this system of records which fall within the scope of 5 U.S.C. 552a(k)(2) may be exempt from the provisions of 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(2). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would place the subject of an investigation on notice that they are under investigation and provide them with significant information concerning the nature of the investigation, thus resulting in a serious impediment to law enforcement investigations. (B) From subsections (d) and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access

rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because there is no necessity for such publication since the system of records will be exempt from the underlying duties to provide notification about and access to information in the system and to make amendments to and corrections of the information in the system. (E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NSA will, nevertheless, continue to publish such a notice in broad generic terms, as is its current practice. (14) System identifier and name. GNSA 17, Employee Assistance Service (EAS) Case Record System. (i) Exemption.

SWID tags support the identification of installed patches, extensible metadata attributes, and software integrity measurement data not supported by CPE. Through these additional capabilities, SWID tags can support more comprehensive software inventory (including patch details), tamper detection, and application whitelisting. Through the fine-grained identification of software products and patches using SWID tags, improved automation of vulnerability and configuration management is possible in SCAP v2. NIST Internal Report (NISTIR) 8060 [5], provides details on the SWID tag format and discussion of the SWID tag operational model, which is intended to be used as part of SCAP v2.

The CAICO is responsible to ensure the separation of duties for individuals volunteering to assist with testing, training, and certification activities. An example of separation of duties is shown in § 170.12(b)(6), which specifies that a CCI cannot be involved in examination activities. DoD modified § 170.8(b)(17)(ii)(G) to add that a consultant is only limited from participation in the assessment process for 36 months. CMMC Ecosystem members do not participate in an assessor capacity on DIBCAC assessments. The DoD declined to add explicit requirements prohibiting ecosystem members from participating in an assessment of an OSC by whom they were previously employed (directly or as a consultant), because the scenario is already covered under § 170.8(b)(17)(ii)(G). DoD disagreed with the comments that a CMMC Ecosystem member is unable to avoid perceived conflicts of interest. The Accreditation Body is required to provide a CoI policy in § 170.8(b)(17) for CMMC Ecosystem members. The Department expects that a reasonable person subject to the CoI policy should understand how to avoid the appearance of conflicts of interest and, if unsure, seek clarity from the Accreditation Body. Details of the disclosure requirements are in the Accreditation Body conflict of interest policy. A satisfactory record of integrity and business ethics is a record that does not indicate derogatory behavior in relation to professional conduct or conflict of interest. The DoD declined to remove the 10-day re-evaluation deadline in §§ 170.17(c)(2) and 170.18(c)(2) to ensure consistency in the assessment process. The OSC may utilize the appeals process, as necessary. The DoD is required to codify CMMC program requirements through a prescribed and formal rulemaking process. The timeline for CMMC implementation changed due in part to DoD's decision to pause and assess the program, seek opportunities to streamline and ease the burden of its implementation, and respond to public comments. The DoD declines to respond to speculative or editorial comments regarding the actions of private citizens, which are not within the scope of this rule. g. Ecosystem Eligibility 1. Foreign Ownership Comment: Two comments noted the rule does not include Foreign Ownership, Control, or Influence (FOCI) requirements for the CAICO. One comment recommended the rule incorporate the definition of the 'national technology and industrial base' and exclude those companies from FOCI requirements. The NTIB includes organizations from the United States, the United Kingdom of Great Britain and Northern Ireland, Australia, New Zealand, and Canada that are engaged in research, development, production, integration, services, or information technology activities. Response:

SECRET cleared contractor personnel under DoD security cognizance and the estimated trips at .89 per

traveler is $(905,818 \times .89 = 813,054)$ estimated trips). Assuming the ratio for those employees reporting foreign travel into APACS is the same as cleared employees would report, of the estimated 813,054 foreign trips by cleared employees, it can be estimated that approximately 181,262 (22.3% of 813,054) will be taken by contractors at small entities, and 631,792 (77.7% of 813,054) by contractors at non-small businesses. It is estimated that it will take a half an hour for a cleared employee to report foreign travel in 2021 and in each of the following years up to year 20 to report foreign travel and receive any pre-travel or post-travel briefings. The estimated average labor rate for a cleared employee to report foreign travel is the equivalent of a GS11 step 5. These assumptions imply costs increasing from \$16.81 to \$19.25 million in each year one through 20.

2. Projected Public Costs. Based on the re-evaluation of the cost of training cleared employees on foreign travel reporting and submissions, the estimated public costs are present value costs of \$267.4 million, which includes the additional foreign travel reporting cost.

3. Updated Baseline Cost. With this increase for the foreign travel reporting, DoD's updated enterprise industrial security baseline cost is estimated not to exceed \$1.753 billion (\$1.486 billion plus \$267.4 million).

Regulatory Analysis Executive Order 12866 , ·Regulatory Planning and Review· and Executive Order 13563 , ·Improving Regulation and Regulatory Review· Executive Orders 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distribute impacts, and equity). Executive Order 13563 emphasizes the importance of quantifying both costs and benefits, reducing costs, harmonizing rules, and promoting flexibility. It has been determined that this rule is a significant regulatory action. Accordingly, the rule has been reviewed by the Office of Management and Budget (OMB) under the requirements of these Executive Orders.

Congressional Review Act This rule is not a ·major rule· as defined by 5 U.S.C. 804(2) . Public Law 96-354, ·Regulatory Flexibility Act· (5 U.S.C. Chapter 6) The Under Secretary of Defense for Intelligence and Security, pursuant to a delegation of authority from the Secretary of Defense, certifies that this rule will not, if promulgated, have a significant economic impact on a substantial number of small business entities in accordance with the Regulatory Flexibility Act (5 U.S.C. 601) requirements since a contractor cleared legal entity may, in entering into contracts requiring access to classified information, negotiate for security costs determined to be properly chargeable by a Government Contracting Activity.

about cybersecurity work. It expresses that work as Task statements and describes Knowledge and Skill statements that provide a foundation for learners including students, job seekers, and employees. The use of these statements helps students to develop skills, job seekers to demonstrate competencies, and employees to accomplish tasks. As a common, consistent lexicon that categorizes and describes cybersecurity work, the NICE Framework improves communication about how to identify, recruit, develop, and retain cybersecurity talent. The NICE Framework is a reference source from which organizations or sectors can develop additional publications or tools that meet their needs to define or provide guidance on different aspects of cybersecurity education, training, and workforce development.

45 CFR 164.308(a)(11)(ii)(B) (1). Back to Citation 591. ·Proposed 45 CFR 164.308(a)(11)(ii)(B) (2). Back to Citation 592. ·Proposed 45 CFR 164.308(a)(11)(ii)(B) (3). Back to Citation 593. · See ·HIPAA Security Rule Security Incident Procedures,· Cybersecurity Newsletter, Office for Civil Rights U.S. Department of Health and Human Services (Oct. 2022), <https://www.hhs.gov/hipaa/for-professionals/security/guidance/cybersecurity-newsletter-october-2022/index.html> . Back to Citation 594. Id. Back to Citation 595. · See ·Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule: A Cybersecurity Resource Guide,· supra note 461. Back to Citation 596. · See Paul Cichonski, et al., ·Computer Security Incident Handling Guide: Recommendations of the National Institute of Standards and Technology,· NIST Special Publication 800-61, Revision 2, National Institute of Standards and Technology, U.S. Department of Commerce (Aug. 2012), <https://www.nist.gov/privacy-framework/nist-sp-800-61> . Back to Citation 597. ·The NIST Cybersecurity Framework (CSF) 2.0,· (removed emphasis on ·Actions regarding a detected cybersecurity incident are taken· in original), supra note 15, p. 9. Back to Citation 598. Id. Back to Citation 599. ·Proposed 45 CFR 164.308(a)(12)(ii)(A) (1). Back to Citation 600. See, e.g., Joint Task Force, ·Security and Privacy Controls for Information Systems and Organizations,· NIST Special Publication 800-53, Revision 5, National Institute of Standards and Technology, U.S. Department of Commerce, p. 157 (Sept. 2020),

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r5.pdf> . Back to Citation 601. ·Cybersecurity Performance Goals,· supra note 18; see also proposed 45 CFR 164.314(a)(2)(i)(C) . Back to Citation 602. ·Cybersecurity Performance Goals,· supra note 18. Back to Citation 603. Id. Back to Citation 604. · See ·Computer Security Incident Handling Guide: Recommendations of the National Institute of Standards and Technology,· supra note 597. Back to Citation 605. See, e.g., ·New York State Register,· supra note 14; ·Invitation for Preliminary Comments on Proposed Rulemaking: Cybersecurity Audits, Risk Assessments, and Automated Decisionmaking,· supra note 14; see also Cal. Civ. Code Section 1798.185. Back to Citation 606. · See ·Plan A. . B. . Contingency Plan!· Cybersecurity Newsletter, Office for Civil Rights, U.S. Department of Health and Human Services (Mar. 2018), <https://www.hhs.gov/sites/default/files/march-2018-ocr-cyber-newsletter-contingency-planning.pdf> . Back to Citation 607. · See Kate Conger, et al., ·What Is CrowdStrike?,· New York Times (July 19, 2024), <https://www.nytimes.com/2024/07/19/business/what-is-crowdstrike.html?searchResultPosition=2>; see also ·Remediation and Guidance Hub: Falcon Content Update for Windows Hosts,· (July 31, 2024), <https://www.crowdstrike.com/falcon-content-update-remediation-and-guidance-hub/> . Back to Citation

means types of assets considered Specialized Assets for CMMC: Government Furnished Equipment, Internet of Things (IoT) or Industrial Internet of Things (IIoT), Operational Technology (OT), Restricted Information Systems, and Test Equipment. (CMMC-custom term) Subcontractor is defined in 48 CFR 3.502-1 . Supervisory Control and Data Acquisition (SCADA) means a generic name for a computerized system that is capable of gathering and processing data and applying operational controls over long distances. Typical uses include power transmission and distribution and pipeline systems. SCADA was designed for the unique communication challenges (e.g., delays, data integrity) posed by the various media that must be used, such as phone lines, microwave, and satellite. Usually shared rather than dedicated, as defined in NIST SP 800-82 Rev 2 (incorporated by reference, see §170.2). System Security Plan (SSP) means the formal document prepared by the information system owner (or common security controls owner for inherited controls) that provides an overview of the security requirements for the system and describes the security controls in place or planned for meeting those requirements. The plan can also contain as supporting appendices or as references, other key security-related documents such as a risk assessment, privacy impact assessment, system interconnection agreements, contingency plan, security configurations, configuration management plan, and incident response plan, as defined in CNSSI 4009 (incorporated by reference, see §170.2). Test Equipment means hardware and/or associated IT components used in the testing of products, system components, and contract deliverables. (CMMC-custom term) User means an individual, or (system) process acting on behalf of an individual, authorized to access a system, as defined in NIST SP 800-53 Rev 5, (incorporated by reference, see §170.2). §170.5 Policy. (a) Protection of FCI and CUI on contractor information systems is of paramount importance to the DoD and can directly impact its ability to successfully conduct essential missions and functions. It is DoD policy that defense contractors and subcontractors shall be required to safeguard FCI and CUI that is processed, stored, or transmitted on contractor information systems by applying specified security requirements. In addition, Defense contractors and subcontractors may be required to implement additional safeguards defined in NIST SP 800-172 (printed page 89123)

DoD has considered previous comments from Small Business Administration (SBA) regarding the impact and cost to small businesses to implement CMMC. In July 2022, the CMMC PMO met with the Office of Advocacy for the U.S. SBA to address the revisions planned in CMMC that are responsive to prior SBA concerns, with which the SBA was satisfied. An Initial Regulatory Flexibility Analysis that includes a detailed discussion and explanation about the assumptions and methodology used to estimate the cost of this regulatory action on small entities follows and is available at www.regulations.gov (search for ·DoD-2023-OS-0063,· click ·Open Docket,· and view ·Supporting Documents·). This final regulatory flexibility analysis has been prepared consistent with 5 U.S.C. 603 . D. Final Regulatory Flexibility Analysis This final regulatory flexibility analysis has been prepared consistent with 5 U.S.C. 604(a) . Reasons for the Action This final rule is necessary to create a secure and resilient supply chain, by addressing threats to the U.S. economy and national security from ongoing malicious cyber activities and preventing theft of hundreds of billions (printed page 83194) of dollars of U.S. intellectual property. The President's Executive Order (E.O.) 14028, ·Improving the Nation's Cybersecurity,· [60] emphasized that industrial security needs strengthening to ensure investments are not lost through intellectual property theft or among other supply chain risks. Currently, the Federal Acquisition Regulation

(FAR) and Defense Federal Acquisition Regulation Supplement (DFARS) prescribe contract clauses intended to protect Federal Contract Information (FCI) and Controlled Unclassified Information (CUI) within the Department of Defense (DoD) supply chain. Specifically, the clause at FAR clause 52.204-21, Basic Safeguarding of Covered Contractor Information Systems, is prescribed at FAR 4.1903 for use in Government solicitations and contracts when the contractor or a subcontractor at any tier may have FCI residing in or transiting through its information system. The FAR clause focuses on ensuring a basic level of cybersecurity hygiene and is reflective of actions that a prudent businessperson would employ.

(c) System Name: Use a short, specific, plain language title that identifies the system's general purpose (limited to 55 characters). (d) System Location: Specify the address of the primary system and any decentralized elements, including automated data systems with a central computer facility and input or output terminals at separate locations. Use street address, 2-letter state abbreviations and 9-digit ZIP Codes. Spell out office names. Do not use office symbols. (e) Categories of Individuals: Describe the individuals covered by the system. Use non-technical, specific categories of individuals about whom the Department of Army keeps records. Do not use categories like "all Army personnel" unless that is truly accurate. (f) Categories of Records in the System: Describe in clear, plain language, all categories of records in the system. List only documents actually kept in the system. Do not identify source documents that are used to collect data and then destroyed. Do not list form numbers. (g) Authority for Maintenance of the System: Cite the specific law or Executive Order that authorizes the maintenance of the system. Cite the DOD directive/instruction or Department of the Army Regulation(s) that authorizes the Privacy Act system of records. Always include titles with the citations. Note: Executive Order 9397 authorizes using the SSN as a personal identifier. Include this authority whenever the SSN is used to retrieve records. (h) Purpose(s): List the specific purposes for maintaining the system of records by the activity. (i) Routine Use(s): The blanket routine uses that appear at the beginning of each Component compilation apply to all systems notice unless the individual system notice specifically states that one or more of them do not apply to the system. Blanket Routine Uses are located at the beginning of the Component listing of systems notices and are not contained in individual system of records notices. However, specific routine uses are listed in each applicable system of records notice. List the specific activity to which the record may be released, for example "To the Veterans Administration" or "To state and local health agencies". For each routine user identified, include a statement as to the purpose or purposes for which the record is to release to that activity. Do not use general statements, such as "To other federal agencies as required" or "To any other appropriate federal agency". (j) Policies and Practices for Storing, Retrieving, Accessing, Retaining, and Disposing of Records in the System: (k) Storage: State the medium in which DA maintains the records; for example, in file folders, card files, microfiche, computer, or a combination of those methods. Storage does not refer to the storage container. (l) Retrievability: State how the Army retrieves the records; for example, by name, fingerprints or voiceprints. (m) Safeguards:

3.1.1 Identifying Possible Sources of Data... 3.1.1 describes the variety of data sources available and discusses actions that organizations can take to support the ongoing collection of data for forensic purposes. 3.1.1 Identifying Possible Sources of Data The increasingly widespread use of digital technology for both professional and personal purposes has led to an abundance of data sources.

Thus, it is critical that regulated entities improve their cybersecurity posture to protect not only against external threats but also (printed page 914) internal ones, and both intentional and accidental breaches. Emergencies or other occurrences can affect the security of ePHI without an intentional act. For example, in 2024, CrowdStrike released a defective update for its software on computers running Microsoft Windows. [225] This update affected the ability of regulated entities to access the ePHI of millions of individuals for varying periods of time. During this time, ePHI was unavailable, meaning that one of the key prongs of the security triad of confidentiality, integrity, and availability was affected. [226] Because of the increased digitization of PHI, it is, for example, essential that covered health care providers engage in thoughtful contingency planning that considers how they will proceed in the event that they are unable to access ePHI in their EHRs. Additionally, threat actors will often seek to take advantage of such incidents. As reported by a large subcontractor of a business associate, less than a week after the outage, the company "observed threat actors leveraging the event to distribute ransomware. [227] The environment in which health care is delivered, the way in which it is

delivered, and the manner in which related information is collected all mean that regulated entities must consider a different approach to operational continuity and resiliency in the face of such challenges. Additionally, they must be wary of the potential for bad actors to attempt to take advantage of such events. C. Regulated Entities' Compliance With the Requirements of the Security Rule Is Inconsistent Despite the proliferation of cybersecurity standards, guidelines, best practices, methodologies, procedures, and processes and the documented increase in unauthorized uses and disclosures of ePHI, many regulated entities have been slow to strengthen their security measures to protect ePHI and their information systems that create, receive, maintain, or transmit it in this new environment. [228] Among the reasons for this are the rapid pace of EHR adoption and digitization of health care, increased connectivity and use of cloud-based infrastructures, limited competition and a stable customer base, limited operating margins, and a failure to invest in cybersecurity infrastructure. [229] For example, regulated entities continue to rely on legacy systems and software that are unsupported by manufacturers, which means that the manufacturers no longer provide security patches or other updates to address security threats and vulnerabilities. [230] In a 2021 survey of health care cybersecurity professionals, 73 percent reported having legacy operating systems. [231] This apparent lack of urgency in adopting new, supported operating systems has serious implications for the confidentiality, integrity, and availability of ePHI.

CIS Safeguard 11.4 · Establish and Maintain an Isolated Instance of Recovery Data Establish and maintain an isolated instance of recovery data. Example implementations include, version controlling backup destinations through offline, cloud, or off-site systems or services. Implementation Groups: 1,2,3 Asset Type: data Security Function: recovery Parent Control: Data Recovery

processes associated with the IoT product, including : - i. Steps taken during development to ensure the IoT product and its product components are free of any known, exploitable vulnerabilities. - ii. The process of working with component suppliers and third-party vendors to ensure the security of the IoT product and its product components is maintained for the duration of its supported lifecycle. - iii. Any post end-of-support considerations, such as the discovery of a vulnerability which would significantly impact the security, privacy, or safety of customers who continue to use the IoT product and its product components. - g. The vulnerability management policies and processes associated with the IoT product, including : - i. Methods of receiving reports of vulnerabilities (see Information and Query Reception below). - ii. Processes for recording reported vulnerabilities. - iii. Policy for responding to reported vulnerabilities, including the process of coordinating vulnerability response activities among component suppliers and third-party vendors. - iv. Policy for disclosing reported vulnerabilities. - v. Processes for receiving notification from component suppliers and thirdparty vendors about any change in the status of their supplied components, such as end of production, end of support, deprecated status (e.g., the product is no longer recommended for use), or known insecurities.

3.1.2 | 3. 3.1.2 Adapt Roles to the Organization The sub-steps for adapting roles to the organization are described in this section.

It has been determined that this rule, as proposed, does impose reporting or recordkeeping requirements under the Paperwork Reduction Act of 1995 (44 U.S.C. 3501 et seq.) (PRA). DoD has submitted an information collection request (ICR) proposal to OMB. See the Supporting Statements in docket number DoD-2023-OS-0097 for specific details and to provide comments on the information collection requirements for the CMMC Program. Comments are invited on: (a) whether the proposed collections of information are necessary for the proper performance of the functions of DoD, including whether the information will have practical utility; (b) the accuracy of the estimate of the burden of the proposed information collections; (c) ways to enhance the quality, utility, and clarity of the information to be collected; and (d) ways to minimize the burden of the information collections on respondents, including the use of automated collection techniques or other forms of information technology. Part A: Estimation of Respondent Burden Hours and Labor Cost For purposes of the proposed rule, DoD is proposing several separate information collections that will be addressed in the CMMC Title 32 Program rule and Title 48 acquisition rule. CMMC Program Information Collections and Recordkeeping Requirements are discussed in four separate groupings: (1) CMMC Level 1 Self-Assessment Collection (2) CMMC Level 2 Self-Assessment Collection (3) CMMC Level 2 Certification Assessment Collection (4) CMMC Level 3 Certification Assessment Collection CMMC

Level 1 Self-Assessment Collection The Level 1 Self-Assessment information collection reporting and recordkeeping requirements will be included in a modification of an existing DFARS collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Modifications to this DFARS collection will be addressed as part of the Title 48 acquisition rule. The information collection reporting and recordkeeping requirements include: OSAs conduct a self-assessment based on NIST guidelines as addressed in § 170.15 of this part. (printed page 89112) This is an assessment to validate implementation of the 15 security requirements listed in FAR clause 52.204-21(b)(1). OSAs upload assessment results and affirmations in SPRS in accordance with § 170.15 and § 170.22 of this part. CMMC Level 2 Self-Assessment Collection The Level 2 Self-Assessment information collection reporting and recordkeeping requirements will be included in a modification of an existing DFARS collection approved under OMB Control Number 0750-0004, Assessing Contractor Implementation of Cybersecurity Requirements. Modifications to this DFARS collection will be addressed as part of the Title 48 acquisition rule. The information collection reporting and recordkeeping requirements include:

From the NIST SP 800-172 Rev 3 Final Public Draft: Finally, a references section lists the source controls 16 With few exceptions, the security controls in SP 800-53 [8] are policy-, technology-, and sector-neutral, meaning that the controls focus on the fundamental measures necessary to protect information across the information life cycle. from SP 800-53 [8] that are associated with the enhanced security requirement. The hyperlink associated with each control provides access to the NIST Cybersecurity and Privacy Reference Tool (CPRT),^{17 17} The final version of SP 800-172r3 and SP 800-172Ar3 will be also be available on CPRT. which includes references to a variety of supporting technical publications. The structure and content of an enhanced security requirement is provided in the example below. 03.13.08E Decoys Use component

, is used to enter into a relationship: (a) Of which the principal purpose is to transfer a thing of value to the recipient to carry out a public purpose of support or stimulation authorized by a law of the United States, rather than to acquire property or services for the USG's direct benefit or use; or, (b) In which substantial involvement is not expected between DoD and the recipient when carrying out the activity contemplated by the award. Throughout this rule, the term grant will include both the grant and cooperative agreement. Grantee means the entity that receives a grant or cooperative agreement. Hand carrier means a cleared employee, designated by the contractor, who occasionally hand carries classified material to its destination in connection with a classified visit or meeting. The classified material remains in the personal possession of the hand carrier except for authorized overnight storage. Home office means the headquarters of a multiple facility entity. Industrial security means that portion of information security concerned with the protection of classified information in the custody of U.S. industry. Information means any knowledge that can be communicated or documentary material, regardless of its physical form or characteristics. Information security means the system of policies, procedures, and requirements established pursuant to executive order, statute, or regulation to protect information that, if subjected to unauthorized disclosure, could reasonably be expected to cause damage to national security. The term also applies to policies, procedures, and requirements established to protect unclassified information that may be withheld from release to the public. Information system means an assembly of computer hardware, software, and firmware configured for the purpose of automating the functions of calculating, computing, sequencing, storing, retrieving, displaying, communicating, or otherwise manipulating data, information and textual material. Insider means cleared contractor personnel with authorized access to any USG or contractor resource, including personnel, facilities, information, equipment, networks, and systems. Insider threat means the likelihood, risk, or potential that an insider will use his or her authorized access, wittingly or unwittingly, to do harm to the national security of the United States. Insider threats may include harm to contractor or program information, to the extent that the information impacts the contractor or agency's obligations to protect classified NSI. Joint venture means an association of two or more persons or entities engaged in a single defined project with all parties contributing assets and efforts, and sharing in the management, profits and losses, in accordance with the terms of an agreement among the parties. KMP

The guidance also recommends establishing a process for measuring contract performance and terminating the contract if security requirements are not being met. Important considerations include: Is there a process for reporting security incidents related to the agreement? Are additional assurances of protections for ePHI from the business associate necessary? If so, where

would such additional assurances be documented (e.g., in the business associate agreement, service-level agreement, or other documentation) and how would they be met (e.g., providing documentation of implemented safeguards, audits, certifications)? The Security Rule requires a regulated entity to protect the confidentiality, integrity, and availability of all ePHI that it creates, receives, maintains, or transmits. [618] It also requires a regulated entity to obtain written satisfactory assurances that its business associate will appropriately safeguard ePHI before allowing the business associate to create, receive, maintain, or transmit ePHI on its behalf. [619] However, the Security Rule does not require a regulated entity to verify that entities that create, receive, maintain, or transmit ePHI on its behalf are in fact taking the necessary steps to protect such ePHI. The lack of such a requirement may leave a gap in protections from risks to ePHI related to regulated entities' vendors and supply chains. Accordingly, the Department proposes several modifications to the Security Rule to provide greater assurance that business associates and their subcontractors are protecting ePHI because a subcontractor to a business associate is also a business associate. The Department proposes to redesignate 45 CFR 164.308(b)(1) and (2) as proposed 45 CFR 164.308(b)(1)(i) and (ii) , respectively. Additionally, we propose to make a technical correction to the standard for business associate contracts and other arrangements for organizational clarity, separating proposed paragraph (b)(1)(i) into paragraphs (b)(1)(i)(A) and (B). We believe this is a non-substantive change that would have no effects on any regulatory, recordkeeping, or reporting requirement, nor would it change the Department's interpretation of any regulation. We also propose to modify both to require a regulated entity to verify that the business associate has deployed the technical safeguards required by 45 CFR 164.312 [620] in addition to obtaining satisfactory assurances that its business associate would comply with the Security Rule. [621] To assist regulated entities in complying with the new standard, we propose to redesignate the implementation specifications at 45 CFR 164.308(b)(3) as 45 CFR 164.308(b)(2) and propose to add an implementation specification for written verification at proposed 45 CFR 164.308(b)(2)(ii) that would require the regulated entity to obtain written verification from the business associate that the business associate has deployed the required technical safeguards. [622]

, (B), (C), and (D) be made available in an appropriate facility where the public may inspect or copy them. This facility is known as the "FOIA reading room". In addition to these records, the DoD Components may elect to place other records in their reading rooms. The DoD Components shall comply with this provision of the FOIA by providing a location accessible to the public for viewing these documents. In lieu of paper copies, the Component may digitize the documents and have them available on a personal computer in the reading room. The DoD Components may share reading room facilities if the public is not unduly inconvenienced, and also may establish decentralized reading rooms. (b) Electronic reading room. The FOIA requires records described in 5 U.S.C. 552(a)(2)(A) , (B), (C), and (D) and created on or after November 1, 1996, be made available electronically. The DoD Components will meet the electronically available requirement by posting the records in an electronic reading room on their FOIA Requester Service Center Web sites. (1) These electronic reading rooms will have four designated sections, each one corresponding to one of the four sections described in paragraph (b) of this section. If a Component does not have relevant documents to post in any of the four sections of the FOIA Requester Service Center electronic reading room, that section of the reading room will contain the annotation that no documents apply. (2) If a DoD Component has documents that meet the qualifications of 5 U.S.C. 552(a)(2)(A) , (B), (C), and (D) posted on a separate Web site, the Component's FOIA Requester Service Center is not required to post these same documents. Instead, the electronic reading room shall link to the other Web site. For example, if a Component maintains electronic copies of its issuances on a separate Web site, then the (a)(2)(C) section of the electronic reading room shall have a link to that site. (3) Exemptions. All information that qualifies for withholding under one or more of the FOIA exemptions described in § 286.14 of this part shall be deleted from all 5 U.S.C. 552(a)(2) records that are made available to the public. § 286.8 Record availability. 5 U.S.C. 552(a)(2)(A) , (B), (C), and (D) records are: (a) "(a)(2)(A)" records. Final opinions, including concurring and dissenting opinions, and orders made in the adjudication of cases, as defined in 5 U.S.C. 551 , that may be cited, used, or relied on as precedents in future adjudications. (b) "(a)(2)(B)" records. Statements of policy and interpretations that have been adopted by the agency and are not published in the Federal Register . (c) "(a)(2)(C)" records.

In model checking, safety refers to the assurance that something undesirable never occurs. This is a fundamental property of an ACP that ensures the absence of safety threats, including privilege

leakage, privilege conflicts, and privilege escalation to unauthorized or unintended principals. Safety can be specified using LTL or CTL languages, which can generally be proven for ACP transition models that describe the safety requirements of any configuration [IR7874]. Formally, a safety property p in LTL or CTL is said to satisfy an ACP transition automaton A if there is no violation of the rules defined by the logic in p . It is assumed that A will eventually

*.Roman numerals in parentheses before the Security Requirement are for numbering purposes only. The numerals are not part of the naming convention for the requirement. (printed page 83227) (d) Implementation. Assessment of security requirements is prescribed by NIST SP 800-171A Jun2018 (incorporated by reference, see §.170.2) and NIST SP 800-172A Mar2022 (incorporated by reference, see §.170.2). Descriptive text in these documents support OSA implementation of the security requirements and use the terms organization-defined and periodically. Except where referring to Organization-Defined Parameters (ODPs), organization-defined means as determined by the OSA. Periodically means occurring at regular intervals. As used in many requirements within CMMC, the interval length is organization-defined to provide contractor flexibility, with an interval length of no more than one year. §.170.15 CMMC Level 1 self-assessment and affirmation requirements. (a) Level 1 self-assessment. To comply with CMMC Level 1 self-assessment requirements, the OSA must meet the requirements detailed in paragraphs (a)(1) and (2) of this section. An OSA conducts a Level 1 self-assessment as detailed in paragraph (c) of this section to achieve a CMMC Status of Final Level 1 (Self). (1) Level 1 self-assessment requirements. The OSA must complete and achieve a MET result for all security requirements specified in §.170.14(c)(2) to achieve the CMMC Status of Final Level 1 (Self). No POA&Ms are permitted for CMMC Level 1. The OSA must conduct a self-assessment in accordance with the procedures set forth in §.170.15(c)(1) and submit assessment results in SPRS. To maintain compliance with the requirements for the CMMC Status of Final Level 1 (Self), the OSA must conduct a Level 1 self-assessment on an annual basis and submit the results in SPRS, or its successor capability. (i) Inputs to SPRS. The Level 1 self-assessment results in the Supplier Performance Risk System (SPRS) shall include, at minimum, the following items: (A) CMMC Level. (B) CMMC Status Date. (C) CMMC Assessment Scope. (D) All industry CAGE code(s) associated with the information system(s) addressed by the CMMC Assessment Scope. (E) Compliance result. (ii) [Reserved] (2) Affirmation. Affirmation of the Level 1 (Self) CMMC Status is required for all Level 1 self-assessments. Affirmation procedures are set forth in §.170.22. (b) Contract eligibility. Prior to award of any contract or subcontract with a requirement for the CMMC Status of Level 1 (Self), OSAs must both achieve a CMMC Status of Level 1 (Self) and have submitted an affirmation of compliance into SPRS for all information systems within the CMMC Assessment Scope. (c) Procedures ·(1) Level 1 self-assessment. The OSA must conduct a Level 1 self-assessment scored in accordance with the CMMC Scoring Methodology described in §.170.24. The Level 1 self-assessment must be performed in accordance with the CMMC Level 1 scope requirements set forth in §.170.19(a) and (b) and the following:

Documents relating to the proceedings before the Board, including the name of the individual initiating NSLRB action, statements of witnesses, reports of interviews and hearings, examiner's findings and recommendations, a copy of the original decision, and related correspondence and exhibits. Authority for maintenance of the system: The National Defense Authorization Act for FY 2004, Public Law 108-136 , Section 1101; 5 U.S.C. 9902(m) , Labor Management Relations in the Department of Defense; and 5 CFR 9901.907 , National Security Labor Relations Board. Purpose(s): To establish a system of records that will document adjudication of unfair labor practice charges, negotiability disputes, exceptions to arbitration awards, and impasses filed with the National Security Labor Relations Board. Routine uses of records maintained in the system, including categories of users and the purposes of such uses: In addition to those disclosures generally permitted under 5 U.S.C. 552a(b) of the Privacy Act, these records or information contained therein may specifically be disclosed outside the DoD as a routine use pursuant to 5 U.S.C. 552a(b)(3) as follows: To the Federal Labor Relations Authority (FLRA) or the Equal Employment Opportunity Commission, when requested, for performance of functions authorized by law. To disclose, in response to a request for discovery or for appearance of a witness, information that is relevant to the subject matter involved in a pending judicial or administrative proceeding. To provide information to officials of labor organizations recognized under 5 U.S.C. 71 when relevant and necessary to their duties of exclusive representation concerning personnel policies, practices, and matters affecting work conditions. The DoD ·Blanket Routine Uses· set forth at the beginning of OSD's compilation of systems of records notices apply to this system. Policies and practices for storing, retrieving, accessing, retaining, and disposing of records in the system: Storage:

Records are maintained on electronic storage media and paper. Retrieval: Records will be retrieved in the system by the following identifiers: assigned case number; individual's name; labor organizations filing the unfair labor practice charges; negotiability disputes; exceptions to arbitration awards; date, month, year or filing; complaint type; and the organizational component from which the complaint arises. Safeguards: Records are maintained in a controlled facility. Physical entry is restricted by the use of locks, guards, and is accessible only to authorized personnel. Access to records is limited to person(s) responsible for servicing the record in performance of their official duties and who are properly screened and cleared for need-to-know. Access to computerized data is restricted by passwords, which are changed periodically. Retention and disposal: Records are disposed of 5 years after final resolution of case. System manager(s) and address:

If CMMC Level 1 or Level 2 Self-Assessment is a contract requirement, the defense contractor will be required to self-assess its compliance with the CMMC Level 1 or Level 2 requirements and submit the assessment results and an affirmation of conformance in SPRS. CMMC Level 1 self-assessment and associated affirmation is required annually. CMMC Level 2 Self-Assessment is required triennially with an affirmation following self-assessment and annually thereafter. If CMMC Level 2 Certification Assessment is a contract requirement, CMMC assessments must be performed by an authorized or accredited CMMC Third Party Assessment Organization (C3PAO). When CMMC Level 3 Certification Assessment is a contract requirement, an assessment by DoD is required following a CMMC Level 2 Final Certification Assessment. Upon completion of a CMMC Level 2 or 3 Certification Assessment, the offeror may be granted a certification of assessment based on the results of the assessment at the appropriate CMMC Level (as described in the CMMC Model). The assessment results are documented in SPRS to enable contracting officers to verify the validity status of an offeror's certification level and currency (i.e., not more than three years old) prior to contract award. The offeror must also submit an affirmation of conformance in SPRS following the assessment and annually thereafter. CMMC allows the use of a Plan of Action and Milestones (POA&Ms) for specified CMMC Level 2 and 3 security requirements. Each POA&M must be closed, i.e., all requirements completed, within 180 days of the initial assessment. The details of the requirements for self-assessment, third-party assessment, and affirmation for each CMMC Level, are provided in §170.15 through §170.18. POA&M requirements, including which requirements are allowed to be on a POA&M and POA&M closeout requirements, in addition to requirements for provision of an affirmation at closeout, contract eligibility, and continuation are provided in §170.21 and §170.22.

Evaluation Assurance 21 Role of Evaluation Assurance Requirements 23 Evaluation Organizations and Processes 25

The reasons for asserting these exemptions is to ensure the integrity of the privacy and civil liberties process. The execution requires that information be provided in a free and open manner without fear of retribution or harassment in order to facilitate a just, thorough, and timely resolution of the complaint or inquiry. Disclosures from this system can enable individuals to conceal their wrongdoing or mislead the course of the investigation by concealing, destroying, or fabricating evidence or documents. In addition, disclosures can subject sources and witnesses to harassment or intimidation which may cause individuals not to seek redress for wrongs through privacy and civil liberties channels for fear of retribution or harassment. (10) System identifier and name. LDIA 0209, Litigation Case Files. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2) , may be exempt pursuant to 5 U.S.C. 552(k)(2) . However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or which he would otherwise be eligible, as a result of maintenance of the information, the individual will be provided access to the information except to the extent that disclosure would reveal the identity of a confidential source. This exemption provides limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. Any portion of this record system which falls within the provisions of 5 U.S.C. 552a(k)(2) and (k)(5) may be exempt from the following subsections of 5 U.S.C. 552a : (c)(3), (d)(1)(2)(3)(4)(5), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I). Exempt materials from other systems of records may in turn become part of the case

records in this system. To the extent that copies of exempt records from those 'other' systems of records are entered into this case record, the Defense Intelligence Agency hereby claims the same exemptions for the records from those 'other' systems that are entered into this system, as claimed for the original primary systems of records, which they are a part. (ii) Authority. 5 U.S.C. 552a(j)(2), (k)(2), (k)(3), (k)(4), (k)(5), (k)(6), and (k)(7). (iii) Reasons. The reason for asserting these exemptions (k)(2) and (k)(5) is to ensure the integrity of the litigation process. (11) System identifier and name. LDIA 10-0004 Occupational, Safety, Health, and Environmental Management Records. (i) Exemption. Any portion of this record system which falls within the provisions of 5 U.S.C. 552a(k)(2)

3.3.1 | Using Existing Competencies... 3.3.1 Using Existing Competencies The NICE Framework Competencies are a way for organizations to align with the NICE Framework at a high level without delving into the details of TKS statements.

Records accuracy assessment . Provide an assessment by the source and recipient agencies as to the quality of the information that will be used for the match. The poorer the quality, the more likely that the program will not be cost-effective. (6) Notice Procedures . Identify what direct and indirect means will be used to inform individuals that matching will take place. (i) Direct notice . Indicate whether the individual is advised that matching may be conducted when he or she applies for a Federal benefit program. Such an advisory should normally be part of the Privacy Act Statement that is contained in the application for benefits. Individual notice sometimes is provided by a separate notice that is furnished the individual upon receipt of the benefit. (ii) Indirect notice . Indicate whether the individual is advised that matching may be conducted by constructive notice. Indirect or constructive notice is achieved by publication of a routine use in the Federal Register when the matching is between agencies or is achieved by publication of the match notice in the Federal Register . (7) Verification procedures . Explain how information produced as a result of the match will be independently verified to ensure any adverse information obtained is that of the individual identified in the match. (8) Due process procedures . Describe what procedures will be used to notify individuals of any adverse information uncovered as a result of the match and to give such individuals an opportunity to either explain the information or how to contest the information. No adverse action shall be taken against the individual until the due process procedures have been satisfied. (i) Unless other statutory or regulatory authority provides for a longer period of time, the individual shall be given 30 calendar days from the date of the notice to respond to the notice. (ii) If an individual contacts the agency within the notice period and indicates his or her acceptance of the validity of the adverse information, the agency may take final action. If the period expires without a response, the agency may take final action. (iii) If the agency determines that there is a potentially significant effect on public health or safety, it may take appropriate action notwithstanding the due process provisions. (9) Security procedures . Describe the administrative, technical, and physical safeguards that will be established to preserve and protect the privacy and confidentiality of the records involved in the match. The level of security must be commensurate with the level of the sensitivity of the records. (10) Records usage, duplication, and redisclosure restrictions . Describe any restrictions imposed by the source agency or by statute or regulation on the collateral uses of the records. Recipient agencies may not use the records obtained for matching purposes for any other purpose absent a specific statutory requirement or where the disclosure is essential to the conduct of the matching program. (11)

(B) In addition to records under the control of NGA, the Threat Mitigation system of records may include records originating from systems of records of other law enforcement and intelligence agencies which may be exempt from certain provisions of the Privacy Act. However, NGA does not assert exemption to any provisions of the Privacy Act with respect to information submitted by or on behalf of individuals. (C) To the extent the Threat Mitigation system contains records originating from other systems of records, NGA will rely on the exemptions claimed for those records in the originating system of records. Exemptions for certain records within the Threat Mitigation system from particular subsections of the Privacy Act are justified for the following reasons: (1) From subsection (c)(3) (Accounting for Disclosures) because giving a record subject access to the accounting of disclosures from records concerning him or her could reveal investigative interest on the part of the recipient agency that obtained the record pursuant to a routine use. Disclosure of the accounting could therefore present a serious impediment to law enforcement efforts on the part of the recipient agency because the individual who is the subject of the record would learn of third agency investigative interests and could take steps to evade detection or apprehension. Disclosure

of the accounting also could reveal the details of watch list matching measures under the Threat Mitigation system, as well as capabilities and vulnerabilities of the watch list matching process, the release of which could permit an individual to evade future detection and thereby impede efforts to ensure security. (2) From subsection (c)(4) because portions of this system are exempt from the access and amendment provisions of subsection (d). (3) From subsection (d) (Access to Records) because access to the records contained in this system of records could inform the subject of an investigation of an actual or potential criminal, civil, or regulatory violation to the existence of that investigation and reveal investigative interest on the part of Department of Homeland Security or another agency. Access to the records could permit the individual who is the subject of a record to impede the investigation, to tamper with witnesses or evidence, and to avoid detection or apprehension. Amendment of the records could interfere with ongoing investigations and law enforcement activities and would impose an unreasonable administrative burden by requiring investigations to be continually reinvestigated. In addition, permitting access and amendment to such information could disclose security sensitive information that could be detrimental to national security. (4

(3) The entity must otherwise meet the entity eligibility determination requirements set out in this rule. (4) Access limitations are inherent with the limited entity eligibility determination and are imposed upon all of the entity's employees regardless of citizenship. (5) Contractors should be aware that the CSA will document the requirements of each limited entity eligibility determination it makes, including the scope of, and any limitations on, access to classified information. (6) Contractors should be aware that the CSA will verify limited entity eligibility determinations only to the requesting GCA. In the case of multiple limited entity eligibility determinations for a single entity, the CSA verifies each one separately only to its requestor. (7) The applicable CSA administratively terminates the limited entity eligibility determination when there is no longer a need for access to the classified information for which the CSA approved the limited entity eligibility determination. (printed page 83328) (n) Termination of the entity eligibility determination. Once granted, a favorable entity eligibility determination remains in effect until terminated or revoked. If the entity eligibility determination is terminated or revoked, the contractor will return all classified material in its possession to the appropriate GCA or dispose of the material as instructed by the CSA. The contractor should be aware that it may request an administrative termination or the CSA may: (1) After coordination with applicable GCAs, administratively terminate the entity eligibility determination because the contractor no longer has a need for access to classified information. (2) Revoke an entity eligibility determination if the contractor is unable or unwilling to protect classified information or is unable to comply with the security requirements of this rule. (o) Invalidation of the entity eligibility determination. The CSA may invalidate an existing entity eligibility determination. While the entity eligibility determination is in an invalidated status, the contractor may not bid on or be awarded new classified contracts or solicitations. The contractor may continue to work on existing classified contracts if the GCA agrees. (p) Records maintenance. Contractors will maintain the original CSA designated forms for the duration of the entity eligibility determination in accordance with CSA-provided guidance. §:117.10 Determination of eligibility for access to classified information for contractor employees. (a) General. (1) The CSA is responsible for determining an employee's eligibility for access to classified information. (i) The contractor must determine that access to classified information is essential in the performance of tasks or services related to the fulfillment of a classified contract. (ii) Access must be clearly consistent with U.S. national security interests as determined by the CSA.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204 and 252 [Docket DARS-2019-0049] RIN 0750-AK14 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Proposed rule. SUMMARY: DoD is proposing to amend the Defense Federal Acquisition Regulation Supplement (DFARS) to modify the text of an existing DFARS clause to clarify its intent and conform its language to current DFARS terminology, pursuant to action taken by the Regulatory Reform Task Force. DATES: Comments on the proposed rule should be submitted in writing to the address shown below on or before December 30, 2019, to be considered in

the formation of a final rule. ADDRESSES: Submit comments identified by DFARS Case 2018-D050, using any of the following methods: · Regulations.gov: <http://www.regulations.gov> · Submit comments via the Federal eRulemaking portal by entering ·DFARS Case 2018-D050· under the heading ·Enter keyword or ID· and selecting ·Search·. Select the link ·Submit a Comment· that corresponds with ·DFARS Case 2018-D050·. Follow the instructions provided at the ·Submit a Comment· screen. Please include your name, company name (if any), and ·DFARS Case 2018-D050· on your attached document. · Email: osd.dfars@mail.mil · Include DFARS Case 2018-D050 in the subject line of the message. · Fax: 571-372-6094. · Mail: Defense Acquisition Regulations System, Attn: Carrie Moore, OUSD(A&S)DPC/DARS, Room 3B941, 3060 Defense Pentagon, Washington, DC 20301-3060. Comments received generally will be posted without change to <http://www.regulations.gov> , including any personal information provided. To confirm receipt of your comment(s), please check www.regulations.gov , approximately two to three days after submission to verify posting, except allow 30 days for posting of comments submitted by mail. FOR FURTHER INFORMATION CONTACT: Ms. Carrie Moore, telephone 571-372-6093. SUPPLEMENTARY INFORMATION: I. Background This rule proposes to modify the clause at DFARS 252.204-7002, Payment for Subline Items Not Separately Priced, to simplify the clause text and conform terminology used in the text to current Government contract line item structure terminology. This update will clarify the intent of the clause, as it pertains to payment on contracts that contain not separately priced (NSP) items, when applicable. The rule also adds a prescription for DFARS 252.204-7002 in the applicable DFARS subpart 204.7109, Contract Clauses. II. Discussion and Analysis

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY DLO NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 ADVERSARY EFFECTS 862

Examples of /uniFB01nal errors include integer over/uniFB02ow , query injec/t\ _i.ligaon, bu/uniFB00er over/uniFB02ow , and side communica/t\ _i.ligaon channels. Legi/t\ _i.ligamate and side channels may also be direct exploit vectors without prior causa/t\ _i.ligaon. Examples of failures include informa/t\ _i.ligaon exposure (IEX) (i.e., con/uniFB01den/t\ _i.ligaality loss), data tampering (TPR) (i.e., integrity loss), denial of service (DOS) (i.e., availability loss), and arbitrary code execu/t\ _i.ligaon (ACE) (i.e., everything could be lost). - Data Tampering (TPR) -Unauthorized modi/uniFB01ca/t\ _i.ligaon or destruc/t\ _i.ligaon of informa/t\ _i.ligaon that leads to integrity loss.

3.1.1 | Notional Risk Management Roles ... 3.1.1 Notional Risk Management Roles An important element of the internal and external context is identifying the relevant work roles for each stage. 3.1.1.

IA.L2-3.5.11 · Obscure Feedback CMMC Assessment Guide · Level 2 | Version 2.13 135 the actual characters. Feedback is obscured based on a defined policy (e.g., smaller devices may briefly show characters before obscuring). Example As a system administrator, you configure your systems to display an asterisk when users enter their passwords into a computer system [a]. For mobile devices, the password characters are briefly displayed to the user before being obscured. This prevents people from figuring out passwords by looking over someone's shoulder. Potential Assessment Considerations · Is the feedback immediately obscured when the authentication is presented on a larger display (e.g., desktop or notebook computers with relatively large monitors) [a]? KEY REFERENCES · NIST SP 800-171 Rev. 2 3.5.11

There may be references in this publication to other publications currently under development by NIST in accordance with its assigned statutory responsibilities. The information in this publication, including concepts and methodologies, may be used by federal agencies even before the completion of such companion publications. Thus, until each publication is completed, current requirements, guidelines, and procedures, where they exist, remain operative. For planning and transition purposes, federal agencies may wish to closely follow the development of these new publications by NIST. The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the

cost-effective security and privacy of other than national security-related information in federal information systems. CWE designators (i.e., CWE-XXXX) are given to weaknesses, views, and categories. A view provides a hierarchical organization of CWEs from a particular perspective (e.g., software development, research, or hardware design). A category is a simpler construct that groups a set of CWEs that have some similarity. Views may contain categories within their hierarchy.

1. Implement a standards-oriented approach to supplier risk to streamline C-SCRM processes : Start with available standards, such as NIST guidance, ISO/IEC 20243, ISO/IEC 27001 series, ISO/IEC 15408, and Federal Information Processing Standard (FIPS)-140. Leveraging an external authority gives the acquirer's supplier security requirements a defensible position and makes compliance attractive to suppliers and business partners concerned about their own security posture. This approach can scale to supply chain demands and be applied to virtually every supplier in every market. 2. Uplift cyber hygiene practices for vendors : Instead of focusing exclusively on manufacturing or logistics processes, work with suppliers to improve their security posture so that they appreciate and fully benefit from enterprise controls such as multi-factor authentication and logical segmentation. Similarly, organizations should evaluate cybersecurity alongside business considerations like financial stability. 3. Invest in unified secure platforms for exchanging information with suppliers : The added confidentiality and authentication provided by these platforms protect the inherently sensitive material in supplier communications, limiting the potential for fraud, theft, and cybersecurity breaches. These platforms also streamline supplier management, simplifying sourcing functions beyond risk management. 4. Develop a central risk management team responsible for the entire organization : The team would be comprised of roles such as Chief Risk Officer, Chief Security Officer, Chief Supply Chain Officer, or other similar roles. This group would work together to address cyber supply chain risks and be responsible for communication and engagement with executive leadership. This team should leverage existing organizational expertise, like information security and compliance functions, when holistically assessing risk. 5.

(E) From subsection (e)(4)(I) because to the extent that this provision is construed to require more detailed disclosure than the broad, generic information currently published in the system notice, an exemption from this provision is necessary to protect the confidentiality of sources of information and to protect privacy and physical safety of witnesses and informants. NSA will, nevertheless, continue to publish such a notice in broad generic terms, as is its current practice. (8) System identifier and name. GNSA 09, Personnel File. (i) Exemption. (A) Investigatory material compiled solely for the purpose of determining suitability, eligibility, or qualifications for federal civilian employment, military service, federal contracts, or access to classified information may be exempt pursuant to 5 U.S.C. 552a(k)(5) , but only to the extent that such material would reveal the identity of a confidential source. (B) Testing or examination material used solely to determine individual qualifications for appointment or promotion in the Federal service may be exempt pursuant to 5 U.S.C. 552a(k)(6) , if the disclosure would compromise the objectivity or fairness of the test or examination process. (C) All portions of this system of records which fall within the scope of 5 U.S.C. 552a(k)(5) and (k)(6) may be exempt from the provisions of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I) and (f). (ii) Authority. 5 U.S.C. 552a(k)(5) and (k)(6) . (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would place the subject of an investigation on notice that they are under investigation and provide them with significant information concerning the nature of the investigation, thus resulting in a serious impediment to law enforcement investigations. (B) From subsections (d) and (f) because providing access to records of a civil or administrative investigation and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding.

. The disclosure of a record outside the Department of Defense for a use that is compatible with the purpose for which the information was collected and maintained by the Department of Defense. The routine use must be included in the published system notice for the system of records involved. (u)

Source agency . Any agency which discloses records contained in a system of records to be used in a computer matching program, or any state or local government, or agency thereof, which discloses records to be used in a computer matching program. (v) Statistical record . A record maintained only for statistical research or reporting purposes and not used in whole or in part in making determinations about specific individuals. (w) System of records . A group of records under the control of a DoD Component from which personal information about an individual is retrieved by the name of the individual or by some other identifying number, symbol, or other identifying particular assigned, that is unique to the individual. §310.5 Policy. It is DoD policy that: (a) The privacy of an individual is a personal and fundamental right that shall be respected and protected. (1) The Department's need to collect, maintain, use, or disseminate personal information about individuals for purposes of discharging its statutory responsibilities shall be balanced against the right of the individual to be protected against unwarranted invasions of their privacy. (2) The legal rights of individuals, as guaranteed by Federal law, regulation, and policy, shall be protected when collecting, maintaining, using, or disseminating personal information about individuals. (3) DoD personnel, to include contractors, have an affirmative responsibility to protect an individual's privacy when collecting, maintaining, using, or disseminating personal information about an individual. (4) Departmental legislative, regulatory, or other policy proposals shall be evaluated to ensure that privacy implications, including those relating to the collection, maintenance, use, or dissemination of personal information, are assessed, to include, when required and consistent with the Privacy Provision of the E-Government Act of 2002 (44 U.S.C. 3501 , Note), the preparation of a Privacy Impact Assessment. (b) Personal information shall be collected, maintained, used, or disclosed to ensure that: (1) It shall be relevant and necessary to accomplish a lawful DoD purpose required to be accomplished by statute or Executive order. (2) It shall be collected to the greatest extent practicable directly from the individual. (3) The individual shall be informed as to why the information is being collected, the authority for collection, what uses will be made of it, whether disclosure is mandatory or voluntary, and the consequences of not providing that information. (4) It shall be relevant, timely, complete, and accurate for its intended use; and

In June 2020, NIST ITL published resources for applying NIST SP 800-63. Based on requests from federal agencies and industry and on recommendations from the U.S. General Accountability Office (GAO), NIST developed and published materials to provide nonnormative guidance for the implementation of SP 800-63A, Enrollment and Identity Proofing ; SP 800-63B, Authentication and Lifecycle Management ; and SP 800-63C, Federation and Assertions . The guidance addresses key topics and aspects of each volume to facilitate the understanding and implementation of the requirements for all assurance levels. ITL presented information for federal agencies and industry to promote the use of the implementation resources and discuss key topics, requirements, and controls and how to properly implement them. Cybersecurity Metrics provide decision support , and they help to measure and improve performance and accountability for cybersecurity activities. A mature metrics program is content-rich, supports a broader range of stakeholders, and provides greater value to the organization. More precise measurement data helps to focus on an actionable approach to improving cybersecurity. To support this effort, NIST has embarked on various initiatives, some of which are highlighted here. Initiatives include research in new technology areas, risk management tools and guidance, and ways for organizations to mature the use of cybersecurity metrics.

that do not specify exactly the type of information to be released, may be honored if it is clear the individual in signing the consent statement intended to obtain a personal benefit (for example, a loan to buy a house) and was aware of the type of information that would be sought. Care should be exercised in these situations to release only the minimum amount of personal information essential to obtain the benefit sought. (5) Do not honor requests from commercial enterprises for official evaluation of personal characteristics, such as evaluation of personal financial habits. §310.24 Disclosures to the public from medical records. (a) Disclosures from medical records are not only governed by the requirement of this part but also by the disclosure provisions of DoD 6025.18-R. (b) Any medical records that are subject to both this part and DoD 6025.18-R may only be disclosed if disclosure is authorized under both. If disclosure is permitted under this part (e.g., pursuant to a routine use), but the disclosure is not authorized under DoD 6025.18-R, disclosure is not authorized. If a disclosure is authorized under DoD 6025.18-R (e.g., releases outside the Department of Defense), but the disclosure is not authorized under this part, disclosure is not authorized. §310.25 Disclosure accounting. (a) Disclosure accountings. (1) Keep an accurate record of all disclosures made from any system of records except disclosures: (i) To DoD personnel for use in the

performance of their official duties; or (ii) Under 5 U.S.C. 552, the FOIA. (2) In all other cases a disclosure accounting is required even if the individual has consented to the disclosure of the information. (3) Disclosure accountings: (i) Permit individuals to determine to whom information has been disclosed; (ii) Enable the activity to notify past recipients of disputed or corrected information (§ 310.19(i)); and (iii) Provide a method of determining compliance with paragraph (c) of § 310.21. (b) Contents of disclosure accountings. As a minimum, disclosure accounting shall contain: (1) The date of the disclosure. (2) A description of the information released. (3) The purpose of the disclosure. (4) The name and address of the person or Agency to whom the disclosure was made. (c) Methods of disclosure accounting. Use any system of disclosure accounting that shall provide readily the necessary disclosure information (see paragraph (a)(3) of this section). (d) Accounting for mass disclosures. When numerous similar records are released, identify the category of records disclosed and include the data required by paragraph (b) of this section in a form that can be used to construct an accounting disclosure record for individual records if required (see paragraph (a)(3) of this section). (e) Disposition of disclosure accounting records. Retain disclosure accounting records for 5 years after the disclosure or the life of the record, whichever is longer. (f) Furnishing disclosure accountings to the individual.

(4) Ensure all Component legislative proposals, policies, or programs having privacy implications, such as the DoD Privacy Impact Assessment Program, are evaluated to ensure consistency with the information privacy principles of this part and DoD 5400.11-R. (5) Assess the impact of technology on the privacy of personal information and, when feasible, adopt privacy-enhancing technology both to preserve and protect personal information contained in Component systems of records and to permit auditing of compliance with the requirements of this part and DoD 5400.11-R. (6) Ensure the DoD Privacy Program periodically shall be reviewed by the Inspectors General or other officials, who shall have specialized knowledge of the DoD Privacy Program. (7) Submit reports, consistent with the requirements of DoD 5400.11-R, as mandated by 5 U.S.C. 552a and OMB Circular A-130, and DoD Directive 5500.1, and as otherwise directed by the DPO. (e) The Secretaries of the Military Departments shall provide support to the Combatant Commands, as identified in DoD Directive 5100.3, [7] in the administration of the DoD Privacy Program. § 310.7 Information requirements. The reporting requirements in § 310.6(d)(7) are assigned Report Control Symbol DD-DA&M(A)1379. § 310.8 Rules of conduct. (a) DoD personnel shall: (1) Take such actions, as considered appropriate, to ensure that personal information contained in a system of records, to which they have access to or are using incident to the conduct of official business, shall be protected so that the security and confidentiality of the information shall be preserved. (2) Not disclose any personal information contained in any system of records except as authorized by DoD 5400.11-R or other applicable law or regulation. Personnel willfully making such a disclosure when knowing that disclosure is prohibited are subject to possible criminal penalties and/or administrative sanctions. (3) Report any unauthorized disclosures of personal information from a system of records or the maintenance of any system of records that are not authorized by this part to the applicable Privacy POC for his or her DoD Component. (b) DoD System Managers for each system of records shall: (1) Ensure that all personnel who either shall have access to the system of records or who shall develop or supervise procedures for handling records in the system of records shall be aware of their responsibilities and are properly trained to safeguard personal information being collected and maintained under the DoD Privacy Program. (2) Prepare promptly any required new, amended, or altered system notices for the system of records and submit them through their DoD Component Privacy POC to the DPO for publication in the Federal Register. (3) Not maintain any official files on individuals which are retrieved by name or other personal identifier without first (printed page 18762) ensuring that a notice for the system of records shall have been published in the Federal Register

(Response) FDA agrees in part with the comments, but has decided not to define ‘perishable food’ in this final rule. FDA defined perishable food in the proposal for the purpose of establishing a shorter record retention time for those foods as opposed to nonperishable foods. FDA has concluded that this objective can be achieved by inserting language directly in § 1.360(b) of this final rule using similar criteria as the NIST definitions for perishable, semi-perishable and long shelf-life food. FDA agrees that the proposed definition is too restrictive for purposes of these final regulations. Therefore, FDA has changed the record retention requirements in § 1.360(b) of this final rule to require record retention for: (1) 6 months for food for which a significant risk of spoilage, loss of value, or loss of palatability occurs within 60 days after the date you receive or release the food; (2) 1 year for food for which a significant risk of spoilage, loss of value, or loss of palatability occurs only after a minimum of 60 days, but within 6 months, after the date you

receive or release the food; and (3) 2 years for food for which a significant risk of spoilage, loss of value, or loss of palatability does not occur sooner than 6 months after the date you receive or release the food, including foods preserved by freezing, dehydrating, or being placed in a hermetically sealed container. However, transporters, or nontransporters retaining records on behalf of transporters, are required to retain for 6 months records for any food having a significant risk of spoilage, loss of value, (printed page 71590) or loss of palatability within 60 days after the date the food is received or released and 1 year for any food having a significant risk of spoilage, loss of value, or loss of palatability only after a minimum of 60 days after the date the food is received or released. FDA chose this approach because: (1) The food industry already is familiar with classification of foods into these three categories due to existing regulations and practices and (2) it will mitigate the problem raised by some comments of inadequate infrastructure for long term storage of records for the shorter shelf life foods. FDA believes that a tracing investigation involving ·perishable· food will not be compromised by providing for the reduced record retention of 6 months because most of these tracebacks are initiated within 6 months of the outbreak.

a. Whether the Department's proposal to provide regulated entities with additional time to revise business associate agreements or other written contracts is appropriate. If not, please explain. b. Whether the Department should also provide group health plans and plan sponsors additional time to revise plan documents by adding a transition provision to grandfather certain existing plan documents for a specified period of time. c. Whether the Department should consider additional constraints or specificity for a new paragraph (d) to allow group health plans more time to comply with the Security Rule requirements for plan documents. J. Section 164.320·Severability The Department intends that, if any provisions of this subpart, including the provisions of this NPRM, if finalized, were held to be invalid or unenforceable facially, or as applied to any person, plaintiff, or stayed pending further judicial or agency action, such provision shall be severable from other provisions of this subpart, and from other rules and regulations currently in effect, and not affect the remainder of this subpart. It is also our intent that, unless such provision shall be held to be utterly invalid or unenforceable, it shall be construed to give the provision maximum effect to the provision permitted by law, including in the application of the provision to other persons not similarly situated or to other dissimilar circumstances from those where the provision may be held to be invalid or unenforceable. The provisions of this subpart, including the proposals of this NPRM, are intended to operate independently of each other, even if multiple provisions serve the same or similar general purpose(s) or policy goal(s). Where a provision is necessarily dependent on another, the context generally makes that clear, such as by cross-reference to a particular standard, requirement, or implementation specification. Where a provision that is dependent on one that is stayed or held invalid or unenforceable, as described in the preceding paragraph, is included in paragraph or section within 45 CFR part 160 or 164 , we intend that other provisions of such paragraph(s) or section(s) that operate independently of said provision would remain in effect. The Department intends the individual standards in 45 CFR 164.308 , 164.310 , 164.312 , 164.314 , and 164.316 to apply separately to govern how a regulated entity must protect the security of all ePHI it creates, receives, (printed page 988) maintains, or transmits. Accordingly, if finalized, this provision would provide that if any one or several standards in 45 CFR 164.308 , 164.310 , 164.312 , 164.314 , and 164.316 are deemed invalid by a court, or non-applicable to a particular person or circumstance, all remaining standards shall be unaffected and shall remain in force, and any remaining component of the adjudicated provision, not invalid or found to be unenforceable or inapplicable, shall be considered by the Department to be still in effect.

, under which records may be disclosed to recipients outside HHS, without the individual record subject's prior written consent: Public disclosures may be made (for example, on FDA's Web site) of the names of commissioned officials, and other basic information, including the identification of their State or local agency, their job titles, the type of commission, any specific commissioned areas, and the date of their commission, to the extent disclosure is not an unwarranted invasion of personal privacy. Disclosure may be made to appropriate Federal Agencies and Department contractors that have a need to know the information for the purpose of assisting the Department's efforts to respond to a suspected or confirmed breach of the security or confidentiality of information maintained in this system of records, provided the information disclosed is relevant and necessary for that assistance. Disclosure may be made to a Federal, State, local, territorial, tribal, foreign, or other public authority, on request, in connection with the hiring or retention of an

employee, the issuance or retention of a security clearance, the letting of a contract, or the issuance or retention of a license, grant, or other benefit, to the extent that the information is relevant and necessary to the requesting Agency's decision. No disclosure will be made unless the information has been determined to be sufficiently reliable to support a referral to another office within the Agency or to another Federal Agency for criminal, civil, administrative, personnel, or regulatory action. Disclosure of system information may be made to a State, local, territorial, and tribal agencies or governments to provide copies of records that were originally provided to the Agency by that entity. Disclosure may be made to Federal Agencies, contractors, and other individuals or entities who perform services for the Agency related to this system of records and who need access to the records to perform those services. Recipients shall be required to comply with the requirements of the Privacy Act of 1974, as amended, 5 U.S.C. 552a . When a record on its face, or in conjunction with other records, indicates a violation or potential violation of law, whether civil, criminal, or regulatory in nature, disclosure may be made to the appropriate public authority, whether Federal, foreign, State, local, or tribal, or otherwise, responsible for enforcing, investigating, or prosecuting such violation, if the information disclosed is relevant to the responsibilities of the Agency or public authority. Disclosure may be made to a court or other tribunal or adjudicative body in a proceeding, when: · The Agency or any component thereof; or · any employee of the Agency in his or her official capacity; or · any employee of the Agency in his or her individual capacity where the Department of Justice (DOJ) has agreed to represent the employee; or

AC.L2-3.1.1 · Authorized Access Control [CUI Data] CMMC Assessment Guide · Level 2 | Version 2.13
 14 Access Control (AC) AC.L2-3.1.1 · AUTHORIZED ACCESS CONTROL [CUI DATA] Limit system access to authorized users, processes acting on behalf of authorized users, and devices (including other systems). ASSESSMENT OBJECTIVES [NIST SP 800-171A]11 Determine if: [a] authorized users are identified; [b] processes acting on behalf of authorized users are identified; [c] devices (and other systems) authorized to connect to the system are identified; [d] system access is limited to authorized users; [e] system access is limited to processes acting on behalf of authorized users; and [f] system access is limited to authorized devices (including other systems). POTENTIAL ASSESSMENT METHODS AND OBJECTS [NIST SP 800-171A] 11 Examine [SELECT FROM: Access control policy; procedures addressing account management; system security plan; system design documentation; system configuration settings and associated documentation; list of active system accounts and the name of the individual associated with each account; notifications or records of recently transferred, separated, or terminated employees; list of conditions for group and role membership; list of recently disabled system accounts along with the name of the individual associated with each account; access authorization records; account management compliance reviews; system monitoring records; system audit logs and records; list of devices and systems authorized to connect to organizational systems; other relevant documents or records]. Interview [SELECT FROM: Personnel with account management responsibilities; system or network administrators; personnel with information security responsibilities]. Test [SELECT FROM: Organizational processes for managing system accounts; mechanisms for implementing account management]. 11 NIST SP 800-171A, p. 9.

Establish and implement as needed a written contingency plan, consisting of written policies and procedures for responding to an emergency or other occurrence including but not limited to fire, vandalism, system failure, natural disaster, or security incident that adversely affects relevant electronic information systems. (ii) Implementation specifications ·(A) Criticality analysis. Perform and document an assessment of the relative criticality of the covered entity's or business associate's relevant electronic information systems and technology assets in its relevant electronic information systems. (B) Data backups. Establish and implement written procedures to create and maintain exact retrievable copies of electronic protected health information, including verification that the electronic protected health information has been copied accurately. (C) Information systems backups. Establish and implement written procedures to create and maintain backups of the covered entity's or business associate's relevant electronic information systems, including verification of success of backups. (D) Disaster recovery plan. (1) Establish (and implement as needed) written procedures to restore loss of the covered entity's or business associate's critical relevant electronic information systems and data within 72 hours of the loss. (2) Establish (and implement as needed) written procedures to restore loss of the covered entity's or business associate's other relevant electronic information systems and data in accordance with the criticality analysis required by paragraph (a)(13)(ii)(A) of this section. (E) Emergency mode operation plan. Establish (and implement as needed) written procedures to enable continuation of

critical business processes for protection of the security of electronic protected health information while operating in emergency mode. (F) Testing and revision procedures. (1) Establish written procedures for testing and revising contingency plans as required by this paragraph (a)(13) in accordance with paragraph (a)(13)(ii)(F)(2) of this section. (2) Review and test contingency plans required by this paragraph (a)(13) at least once every 12 months, document the results of such tests, and modify such contingency plans as reasonable and appropriate in accordance with the results of those tests. (printed page 1016) (14) Standard: Compliance audit. Perform and document an audit at least once every 12 months of the covered entity's or business associate's compliance with each standard and implementation specification in this subpart. (b)(1) Standard: Business associate contracts and other arrangements.

DoD uses this information to control unclassified contract data that is sensitive and inappropriate for release to the public; and to facilitate data exchange among automated systems for contract award, contract administration, and contract payment by assigning a unique code to each DoD contractor. Affected Public: Businesses or other for-profit and not-for-profit institutions: Annual Burden Hours: 13,758. Number of Respondents: 22,602. Responses Per Respondent: 1. Annual Responses: 22,602. Average Burden Per Response: .61 hours. Frequency: On occasion. Summary of Information Collection DFARS 204.404-70(a) prescribes use of the clause at DFARS 252.204-7000, Disclosure of Information, in contracts that require the contractor to access or generate unclassified information that may be sensitive and inappropriate for release to the public. The clause requires the contractor to obtain approval of the contracting officer before release of any unclassified contract-related information outside the contractor's organization, unless the information is already in the public domain. In requesting this approval, the contractor must identify the specific information to be released, the medium to be used, and the purpose for the release. DFARS 204.603(1) prescribes use of the provision at DFARS 252.204-7001, Commercial and Government Entity (CAGE) Code Reporting, in solicitations when CAGE codes for potential offerors are not available to the contracting officer. The provision requires an offeror to enter its CAGE code on its offer. If an offeror does not have a CAGE code, the offeror may request one from the contracting officer, who will ask the offeror to complete Section B of DD Form 2051, Request for Assignment of a Commercial and Government Entity (CAGE) Code. Michele P. Peterson, Executive Editor, Defense Acquisition Regulations Council. [FR Doc. 01-3743 Filed 2-13-01; 8:45 am] BILLING CODE 5000-04-M

CMVP; Cryptographic Module Validation Program; FIPS 140; FIPS 140 testing; ISO/IEC 19790; ISO/IEC 24759; security policy; testing requirement; vendor documentation; vendor evidence. This document is intended for vendors, testing labs, and CMVP to address issues in ISO/IEC 19790, Information technology - Security techniques - Security requirements for cryptographic modules , and ISO/IEC 24759, Information technology - Security techniques - Test requirements for cryptographic modules . This document specifies the Cryptographic Module Validation Program (CMVP) modifications of the methods to be used by a Cryptographic and Security Testing Laboratory (CSTL) to demonstrate conformance. This document also specifies the modification of documentation for providing evidence to demonstrate conformity. Unless otherwise specified in this document, the test requirements are specified in ISO/IEC 19790 Annex B and ISO/IEC 24759 Section 6.14.

From the NIST SP 800-172 Rev 3 Final Public Draft: <https://doi.org/10.6028/NIST.SP.800-172r3.fpd>
Author ORCID iDs Ron Ross: 0000-0002-1099-9757 Victoria Pillitteri: 0000-0002-7446-7506 Enhanced Security Requirements for Protecting CUI NIST SP 800-172r3 fpd (Final Public Draft) September 2025 Public Comment Period September 29, 2025 · November 14, 2025 January 16, 2026 Submit Comments 800-171comments@list.nist.gov National Institute of Standards and Technology Attn: Computer Security Division, Information Technology Laboratory 100 Bureau Drive (Mail Stop 8930) Gaithersburg, MD 20899-8930 All comments submitted during the public comment period will be posted to the NIST page. with contact information redacted. All technical content will be posted as submitted, so commenters should not include information they do not wish to be

3.2.14 | IP-3 | XFC/EVSE | This may include development systems, operational systems, and IT/ICS systems.

Blockchain for Access Control Systems ## Blockchain for Access Control Systems The rapid development and wide application of distributed network systems have made network security - especially access control and data privacy - ever more important. Blockchain technology offers

features such as decentralization, high confidence, and tamper-resistance, which are advantages to solving auditability, resource consumption, scalability, central authority, and trust issues - all of which are challenges for network access control by traditional mechanisms. This document presents general information for blockchain access control systems from the views of blockchain system properties, components, functions, and supports for access control policy models. Considerations for implementing blockchain access control systems are also included.

(L) From subsection (g) because portions of this system of records are compiled for law enforcement purposes and have been exempted from the access provisions of subsections (d) and (f). (10) System identifier and name. A0190-14 OPMG, Registration and Permit Files. (i) Exemption. Investigatory material compiled for law enforcement purposes, other than material within the scope of subsection 5 U.S.C. 552a(j)(2), is exempt pursuant to 5 U.S.C. 552a(k)(2). However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law or for which he would otherwise be eligible, as a result of the maintenance of such information, the individual will be provided access to such information except to the extent that disclosure would reveal the identity of a confidential source. Therefore, portions of this system of records may be exempt pursuant to 5 U.S.C. 552a(k)(2) from subsections 5 U.S.C. 552a(c)(3), (d), (e)(1), (e)(4)(G), (e)(4)(H), (e)(4)(I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2). (iii) Reasons. (A) From subsection (c)(3) because the release of the disclosure accounting would permit the subject of a criminal investigation or matter under investigation to obtain valuable information concerning the nature of that investigation which will present a serious impediment to law enforcement. (B) From subsection (d) because access to the records contained in this system would inform the subject of a criminal investigation of the existence of that investigation, provide the subject of the investigation with information that might enable him to avoid detection or apprehension, and would present a serious impediment to law enforcement. (C) From subsection (e)(1) because in the course of criminal investigations, information is often obtained concerning the violations of laws or (printed page 14750) civil obligations of others not relating to an active case or matter. In the interests of effective law enforcement, it is necessary that this valuable information is retained since it can aid in establishing patterns of activity and provide valuable leads for other agencies and future cases that may be brought. (D) From subsections (e)(4)(G) and (e)(4)(H) because portions of this system of records have been exempted from the access provisions of subsection (d), making these subsections not applicable. (E) From subsection (e)(4)(I) because the identity of specific sources must be withheld in order to protect the confidentiality of the sources of criminal and other law enforcement information. This exemption is further necessary to protect the privacy and physical safety of witnesses and informants. (F) From subsection (f) because portions of this system of records have been exempted from the access provisions of subsection (d). (11) System identifier and name. A0190-45 OPMG, Military Police Reporting Program Records (MPRP). (i) Exemption. Parts of this system may be exempt pursuant to 5 U.S.C. 552a(j)(2).

When a contractor is potentially collocated with or in close proximity to its foreign parent or an affiliate, the contractor will provide a facilities location plan that identifies the physical locations of the contractor and its foreign parent(s) or affiliate(s) respectively. The facilities location plan will assist the CSA in determining if the contractor is collocated or if the close proximity can be allowed under the FOCI mitigation plan. A U.S. entity generally cannot be collocated with the foreign parent or affiliate, i.e., at the same address or in the same location. * * * * § 117.12 [Amended] 8. Amend § 117.12 in paragraph (k) by removing the words "every 12 months" and adding in their place the words "at least annually". 9. Amend § 117.15 by: a. Revising paragraph (a) introductory text; b. Redesignating paragraphs (a)(2) and (a)(3) as paragraphs (a)(3) and (a)(4); c. Adding new paragraph (a)(2); d. In the newly redesignated paragraph (a)(3), revising the heading; e. In the newly redesignated paragraph (a)(4), redesignating paragraphs (ii), (iii), and (iv) as paragraphs (iii), (iv), and (v); f. In the newly redesignated paragraph (a)(4), adding a new paragraph (ii); (printed page 86294) g. In the newly redesignated paragraph (a)(4)(iv)(B), adding the word "effects" after the word "personal"; h. Revising paragraph (c) introductory text; i. Revising paragraph (d)(3)(i)(A); j. Revising paragraph (e)(1)(ii) and paragraph (e)(2) introductory text; k. Adding a new paragraph (e)(2)(viii); and l. Revising paragraph (e)(6). The revisions and additions read as follows: § 117.15 Safeguarding classified information. (a) General safeguarding. Contractors will be responsible for safeguarding classified information in their custody or under their control, with approval for such storage of classified information by the applicable CSA. Individuals are responsible for safeguarding classified information entrusted to them. Contractors will provide the

extent of protection to classified information in accordance with the provisions of this rule. * *

* * * (2) Restricted areas. When it is necessary to control access to classified material and an open storage area is not available, a restricted area may be established. A restricted area will normally become necessary when it is impractical or impossible to protect classified material because of its size, quantity, or other unusual characteristic. The restricted area shall have a clearly defined perimeter, but physical barriers are not required. Personnel within the area shall be responsible for challenging all persons who may lack appropriate need-to-know for the information within the restricted area. All classified material will be secured during non-working hours in approved repositories, in accordance with the provisions of this rule, or secured using other methods approved by the CSA. (3) Security checks. * * * (4) * * *

(7) This exemption also applies when the fact of the existence or nonexistence of a responsive record would itself reveal information in which a privacy interest exists, and the public interest in disclosure is not sufficient to outweigh the privacy interest. In this situation, the DoD Components shall neither confirm nor deny the existence or nonexistence of the record being requested. This is known as a 'Glomar response', and Exemption 6 must be cited in the response. Refusal to confirm or deny should not be used when: (i) The person whose personal privacy is in jeopardy has provided the requester with a privacy waiver. (ii) The person seeking access to an agency record initiated or directly participated in an investigation that leads to the creation of that record. (iii) The person whose personal privacy is in jeopardy is deceased, the agency is aware of that fact, and disclosure would not invade the privacy of the deceased's family. (g) Exemption 7 . Pursuant to 5 U.S.C. 552(b)(7) , records or information compiled for law enforcement purposes are exempt from disclosure upon the identification of one of the six harms delineated in the 6 subparts of Exemption 7. Law enforcement purposes include civil, criminal, military, regulatory, and administrative law, including the implementation of Executive Orders or regulations issued pursuant to law. This exemption may be invoked to prevent disclosure of documents not originally created for, but later gathered for, law enforcement purposes. (1) Conditions under which exception 7 applies. Exemption 7 applies only when production of such law enforcement records or information: (i) Exemption 7A. This applies when the disclosure of law enforcement records could reasonably be expected to interfere with enforcement proceedings (5 U.S.C. 552(b)(7)(A)). (ii) Exemption 7B. This applies when the disclosure of law enforcement records would deprive a person of the right to a fair trial or to an impartial adjudication (5 U.S.C. 552(b)(7)(B)). (iii) Exemption 7C . This applies when the disclosure of law enforcement records could reasonably be expected to constitute an unwarranted invasion of the personal privacy of a living person, including surviving family members of an individual identified in such a record (5 U.S.C. 552(b)(7)(C)). (iv) Exemption 7D . This applies when the disclosure of law enforcement records could reasonably be expected to disclose the identity of a confidential source, including a source within the Department of Defense; a state, local, or foreign agency or authority; or any private institution that furnishes the information on a confidential basis; and could disclose information furnished from a confidential source and obtained by a criminal law enforcement authority in a criminal investigation or by an agency conducting a lawful national security intelligence investigation (section 5 U.S.C. 552(b)(7)(D)). (v) Exemption 7E.

| access category | One of the classes to which a user, program or process in an ADP system may be assigned on the basis of the resources or groups of resources that each is authorized to use. (AR 380-380; FIPS PUB 39) | |-----|-----|

-----| | access control | 1) The process of limiting access to the resources of a system to authorized users, programs, processes or other systems (in networks). (AR 380-380) | | access control list | A list of subjects which are authorized to have access to some object. (IV1TR-8201) | |-----|-----|

-----| | access control measures | Hardware and software features, physical controls, operating procedures, management procedures, and various combinations of these designed to detect or prevent unauthorized access to an ADP system and to enforce access control. (DOE 5637.1) | | access control mechanism(s) | Hardware or software features, operating procedures, management procedures, and various combinations of these designed to detect and prevent unauthorized access and to permit authorized access to an automated system. (AR 380-380; FIPS PUB 39) | | access control roster | A list of human and computer users who communicate or interface with a system, that documents the

degree of access and control for each user.

The Department believes that determinations of risk level and criticality may vary based on the specific type of regulated entity and the regulated entity's specific circumstances. For example, a health care provider must consider the higher levels of risks to physical and technical security that are created by regular entry and exit of individuals seeking health care and other members of the public into its facilities, creating potentially numerous avenues for access to ePHI through technology assets; in contrast, a health plan that generally does not permit physical entry by individuals into its office building may determine that the risks to ePHI from physical entry by individuals or other members of the public is low because its workforce members do not generally physically interact with the public. As another example, a vulnerability permitting unauthenticated remote code execution on a device connected to a regulated entity's relevant electronic information systems would likely constitute either a high or critical risk. However, should such a device not have the ability to connect to the network, the risk might be low or moderate because the likelihood of triggering a network vulnerability on a non-networked device is low, even though the impact of such trigger might be high. Thus, it is essential that a regulated entity consider its specific circumstances when assessing the criticality of a risk and to address such risks in a manner that is appropriate to its specific facts and circumstances. [473] In yet another example, a regulated entity in possession of legacy devices or devices that are nearing the end of their lifespan should assess the risks associated with continued use of such devices as part of its risk analysis and ensure that replacement of such devices and/or the implementation of compensating controls are included in its risk management plan. Despite our having made available an abundance of free and widely-publicized guidance tools, OCR unfortunately has learned through its compliance and enforcement activities that regulated entities often do not perform compliant risk analyses. As discussed above, in 2016 and 2017, the Department conducted audits of 166 covered entities and 41 business associates for their compliance with selected provisions of the HIPAA Rules. [474] These audits confirmed that only small percentages of covered entities (14 percent) and business associates (17 percent) were substantially fulfilling their regulatory responsibilities to safeguard ePHI they hold through risk analysis activities. Entities generally failed to: Identify and assess the risks to all of the ePHI in their possession or even develop and implement policies and procedures for conducting a risk analysis. Identify threats and vulnerabilities to consider their potential likelihoods and effects, and to rate the risk to ePHI.

Together, the annual cost to a contractor to obtain an independent assessment of the security of a FIS is approximately \$132,000 (\$52,000 + 80,000). ii. Cyber Threat Hunting and Vulnerability Assessment. The (printed page 68409) Government estimates that four senior level employees will expend a total of 448 hours (4 individuals * 8 hours * 14 days) to complete cyber threat hunting and the vulnerability assessment of a FIS. Using an average loaded wage rate of \$250.00 for a cyber threat hunter/vulnerability assessor, the Government estimates the annual cost for a contractor to conduct a cyber threat hunting and vulnerability assessment of a FIS is approximately \$112,000 (448 hours * \$250). iii. Submission of Assessments. The Government estimates a contractor will spend one hour preparing and submitting each assessment to the Government. Using an average loaded wage rate of \$91.10 for FIS occupations, the total annual estimated cost for a contractor that operates or maintains a non-cloud FIS designated as a moderate or high FIPS 199 impact to submit both assessments to the Government is approximately \$182 (1 hour * 2 responses * \$91.10). 4. Submission of a Continuous Monitoring Strategy Paragraph (f)(7) of the new clause 52.239-YY requires a contractor that develops, implements, operates, or maintains a non-cloud FIS to provide the Government with a continuous monitoring strategy for the FIS (as developed under NIST SP 800-53) that demonstrates an ongoing awareness of information security, vulnerabilities, and threats in order to support risk management decisions, and applies the use of automation, wherever possible; protects vulnerability scan data, logs, and telemetry; and applies the guidance of NIST SP 800-137, Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations. All 28 contractors awarded a contract involving a non-cloud FIS will be required to develop or update their continuous monitoring strategy to meet the requirements of this rule. Many contractors will have developed a continuous monitoring strategy to comply with the guidance in NIST 800-53; however, those plans may need to be revised to demonstrate a continuous monitoring strategy. The Government estimates a contractor will spend, on average, 160 hours developing and/or documenting a continuous monitoring strategy, revising their existing strategy, as needed, and submitting the strategy to the Government. Using an average loaded wage rate of \$91.10 for FIS occupations, the total annual estimated cost for a contractor that operates or maintains a non-cloud

FIS to submit a continuous monitoring strategy to the Government is approximately \$14,600 (160 hours * \$91.10).

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: DEPARTMENT OF DEFENSE 6000 DEFENSE PENTAGON WASHINGTON, D.C. 20301-6000 "Protecting Controlled Unclassified Information in Organizations," NIST Special Publication (MEMORANDUM FOR SENIOR PENTAGON LEADERSHIP COMMANDERS OF THE COMBATANT COMMANDS DEFENSE AGENCY AND DOD FIELD ACTIVITY DIRECTORS SUBJECT: Department of Defense Organization-Defined Parameters for National Institute of Standards and Technology Special Publication 800-171 Revision 3 Reference: (a) National Institute of Standards and Technology (NIST) Special Publication, Nonfederal Systems and SP) 800-171 Revision 3, May 2024 A key aspect of reference (a) is the inclusion of organization-defined parameters (ODPs), which allow organizations to tailor select security controls to specific security requirements, as dete

4. Recommendations to minimize the information collection burden on the affected public, including automated collection techniques. The PRA requires consideration of the time, effort, and financial resources necessary to meet the information collection requirements referenced in this section. The Department solicits public comments on its assumptions and burden estimates in this NPRM as summarized below. In this RIA, the Department proposes to revise certain information collection requirements associated with this NPRM and, as such, would revise the information collection last prepared in 2024 and approved under OMB control #0945-0003. [1033] The proposed revisions to the information collection describe all new and adjusted information (printed page 1010) collection requirements for regulated entities pursuant to the implementing regulation for HIPAA at 45 CFR parts 160 and 164 , the HIPAA Privacy, Security, Breach Notification, and Enforcement Rules (-HIPAA Rules-). The estimated annual labor burden presented by the regulatory modifications is 77,067,552 burden hours at a first-year cost of \$9,314,106,174. These figures, respectively, represent the sum of 37,781,637 new burden hours at a cost of \$4,655,324,954 for compliance by regulated entities and 39,285,915 new burden hours at a cost of \$4,658,781,219 for compliance by health plan sponsors. The overall total burden for respondents to comply with the information collection requirements of all of the HIPAA Privacy, Security, and Breach Notification Rules, including new burdens presented by proposed program changes, is estimated to be 925,144,023 burden hours at a cost of \$109,085,104,674, plus \$163,499,411 in capital costs for a total estimated annual burden of \$109,248,604,085, after the effective date of the final rule. This estimate is based on a total of 1,202,562,864 responses for a total of 2,565,011 respondents. The total burden for the HIPAA Rules, including the changes proposed in this NPRM, would result in a decrease of 28,838,213 burden hours and a cost increase of \$1,911,898,144, in comparison to the baseline in the ICR associated with the 2024 Privacy Rule to Support Reproductive Health Care Privacy. [1034] This is the result of multiples changes, such as decreasing burden hours for some existing requirements, increasing the estimated number of covered entities, adding new Security Rule requirements, and expanding the pool of respondents for the Security Rule by adding requirements for health plan sponsors. Details describing the burden analysis for the proposals associated with this RIA are presented below and explained further in the ICR associated with the NPRM. 1. Explanation of Estimated Annualized Burden Hours

As defined in section 4.1901 of the FAR, FCI means information, not intended for public release, that is provided by or generated for the Government under a contract to develop or deliver a product or service to the Government, but not including information provided by the Government to the public, such as that on public websites, or simple transactional information, such as that necessary to process payments. Controlled Unclassified Information (CUI): 32 CFR 2002.4(h) defines CUI, in part, as information the Government creates or possesses, or that an entity creates or possesses for or on behalf of the Government, that a law, regulation, or Government-wide policy requires or permits an agency to handle using safeguarding or dissemination controls, including FCI. In September 2020, the DoD published DFARS interim rule (Case 2019-D041), which implemented DoD's initial vision for the Cybersecurity Maturity Model Certification (CMMC) Program (-CMMC 1.0-) and outlined basic program features, to include: 5-level tiered model, CMMC Certified Third Party Assessment Organization (C3PAO) assessments in support of contractor and subcontractor certification, with no allowance for a Plan of Action and Milestones, and implementation of all security requirements by the time of a contract award. A total of 750 comments were received on the CMMC Program during the public comment period that ended on November 30, 2020. These comments highlighted a variety of industry concerns including concerns relating to the costs for a C3PAO certification, and the costs and burden associated with implementing, prior to award, the required

process maturity and 20 additional cybersecurity practices that were included in CMMC 1.0. The Small Business Administration Office of Advocacy also raised similar concerns on the impact the rule would have on small businesses in the DIB. Pursuant to DFARS clause 252.204-7012, DoD has required certain defense contractors and subcontractors to implement the security protections set forth in the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-171 Rev 2 to provide adequate security for sensitive unclassified DoD information that is processed, stored, or transmitted on contractor information systems and to document their implementation status, including any plans of action for any NIST SP 800-171 Rev 2 requirement not yet implemented, in a System Security Plan. The CMMC Program provides the Department the mechanism needed to verify that a defense contractor or subcontractor has implemented the security requirements at each CMMC Level and is maintaining that status across the contract period of performance, as required.

and a copy to the Defense Acquisition Regulations System, Attn: Ms. Veronica Fallon, OUSD(AT&L)DPAP/DARS, Room 3B855, 3060 Defense Pentagon, Washington, DC 20301-3060. Comments can be received from 30 to 60 days after the date of this notice, but comments to OMB will be most useful if received by OMB within 30 days after the date of this notice. Public comments are particularly invited on: Whether this collection of information is necessary for the proper performance of functions of the DFARS, and will have practical utility; whether our estimate of the public burden of this collection of information is accurate, and based on valid assumptions and methodology; ways to enhance the quality, utility, and clarity of the information to be collected; and ways in which we can minimize the burden of the collection of information on those who are to respond, through the use of appropriate technological collection techniques or other forms of information technology. To request more information on this proposed information collection or to obtain a copy of the proposal and associated collection instruments, please write to the Defense Acquisition Regulations System, Attn: Ms. Veronica Fallon, OUSD(AT&L)DPAP/DARS, Room 3B855, 3060 Defense Pentagon, Washington, DC 20301-3060, or email dfars@osd.mil. Include DFARS Case 2011-D044 in the subject line of the message. List of Subjects in 48 CFR Parts 204, 212, and 252 Government procurement Mary Overstreet, Editor, Defense Acquisition Regulations System. Therefore 48 CFR parts 204, 212, and 252 are proposed to be amended as follows: 1. The authority citation for 48 CFR parts 204, 212, and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1. PART 204-ADMINISTRATIVE MATTERS 2. Section 204.1202 is amended by- a. Redesignating paragraphs (2)(i) through (xiii) as paragraphs (2)(ii) through (xiv); and b. Adding new paragraph (2)(i) to read as follows: 204.1202 Solicitation provision and contract clause. * * * * * (2) * * * (i) 252.204-70XX, Ownership of Offeror. * * * * * 3. Section 204.7207 is revised to read as follows: (printed page 43479) 204.7207 Solicitation provisions. (a) Use the provision at 252.204-7001, Commercial and Government Entity (CAGE) Code Reporting, in solicitations when- (1) The solicitation does not include the clause at FAR 52.204-7, Central Contractor Registration; and (2) The CAGE codes for the potential offerors are not available to the contracting office. (b) Use the provision at 252.204-70XX, Ownership of Offeror, in all solicitations. PART 212-ACQUISITION OF COMMERCIAL ITEMS 4. Section 212.301 is amended by- a. Redesignating paragraphs (f)(iv)(C) through (Q) as paragraphs (f)(iv)(D) through (R); and b. Adding a new paragraph (f)(iv)(C) to read as follows: 212.301 Solicitation provisions and contract clauses for the acquisition of commercial items. * * * * * (iv) * * * (C) Use the provision at 252.204-70XX Ownership of Offeror, as prescribed in 204.7207. * * * * * PART 252-SOLICITATION PROVISIONS AND CONTRACT CLAUSES 252.204-7001

. If an individual disagrees with the denial decision, he or she may file an appeal within 60 calendar days of receipt of the denial notification. Appeals should be sent to: NGB Chief Counsel, 1636 Defense Pentagon, Room 1D164, Washington DC 20301-1636. (5) The Chief Counsel will use the following procedures for any appeals received: (i) The Chief Counsel will notify Chief of the OIP that an appeal has been received and request an exact copy of the administrative record be provided within 10 working days. (ii) The Chief Counsel will review the appeal and make a final determination on whether to grant or deny the appeal. (A) If the Chief Counsel denies the appeal, a written letter will be provided to the requestor using the procedures outlined in 32 CFR part 310, subpart D including notification to the requestor that they may file a statement of disagreement. A brief statement will be prepared by the NGB Chief Counsel summarizing the reasons for refusing to amend the records and a copy will be provided to the Chief of the OIP and the System Manager. (B) If the appellate authority grants the appeal, the procedures outlined in 32 CFR part 310, subpart D and this part will be followed. The System Manager will be responsible for informing all previous recipients of the amendment when a disclosure accounting has been maintained in accordance with 32

CFR part 310, subpart E . (iii) All appeals should be processed within 30 working days after receipt by the Chief Counsel. If the Chief Counsel determines that a fair and equitable review cannot be made within that time, the individual shall be informed in writing of the reasons for the delay and of the approximate date the review is expected to be completed. (g) Disclosure of Disputed Information. If the appellate authority determines the record should not be amended and the individual has filed a statement of disagreement, the following procedures will be used: (1) The System Manager that has control of the record shall annotate the disputed record so it is apparent to any person to whom the record is disclosed that a statement has been filed. Where feasible, the notation itself shall be integral to the record. (2) Where disclosure accounting has been made, the System Manager shall advise previous recipients that the record has been disputed and shall provide a copy of the individual's statement of disagreement, and the statement summarizing the reasons for the NGB refusing to amend the records in accordance with 32 CFR part 310, subpart D . (3) The statement of disagreement shall be maintained in a manner that permits ready retrieval whenever the disputed portion of the record is disclosed. (4) When information that is the subject of a statement of disagreement is subsequently requested for disclosure, the System Manager will follow these procedures: (i) The System Manager shall note which information is disputed and provide a copy of the individual's statement in the disclosure.

Under DFARS clause 252.204-7012, defense contractors and subcontractors must document implementation of the security requirements in NIST SP 800-171 Rev 2 in a system security plan and may use a Plan of Action Milestones to describe how and when any unimplemented security requirements will be met. For the CMMC Program, the solicitation, will specify the required CMMC level, which will be determined considering program criticality, information sensitivity, and severity of cyber threat. Although the security requirements in NIST SP 800-171 Rev 2 address a range of threats, additional requirements are needed to significantly reduce the risk posed by APTs. An APT is an adversary that possesses sophisticated levels of expertise and significant resources that allow it to create opportunities to achieve its objectives by using multiple attack vectors (e.g., cyber, physical, and (printed page 89083) deception). CMMC Level 3 requires implementation of selected security requirements from NIST SP 800-172 to reduce the risk of APT threats. The CMMC Program will require prime contractors to flow the appropriate CMMC requirement down throughout the entire supply chain relevant to a particular contract. Defense contractors or subcontractors that handle FCI, must meet the requirements for CMMC Level 1. Defense contractors that handle CUI must meet the requirements for CMMC Level 2 or higher, depending on the sensitivity of the information associated with a program or technology being developed. Scale and Depth Today, DoD prime contractors must include DFARS clause 252.204-7012 in subcontracts for which performance will involve covered defense information, but this does not provide the Department with sufficient insights with respect to the cybersecurity posture of all members of a multi-tier supply chain for any given program or technology development effort. CMMC 2.0 requires prime contractors to flow down appropriate CMMC Level requirements, as applicable, to subcontractors throughout their supply chain(s). Given the size and scale of the DIB, the Department cannot scale its existing cybersecurity assessment capability to conduct on-site assessments of approximately 220,000 DoD contractors and subcontractors every three years. The Department's existing assessment capability is best suited for conducting targeted assessments for the relatively small subset of DoD contractors and subcontractors that support designated high-priority programs involving CUI.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 204 and 252 [Docket DARS-2017-0015] RIN 0750-AJ54 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD is issuing a final rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to remove a provision that is duplicative of an existing Federal Acquisition Regulation (FAR) provision that requires a vendor to enter Commercial and Government Entity (CAGE) code information into a Governmentwide database prior to award of any contract or agreement. DATES: Effective May 30, 2018. FOR FURTHER INFORMATION CONTACT: Ms. Carrie Moore, telephone 571-372-6093. SUPPLEMENTARY INFORMATION: I. Background DoD is amending the DFARS to remove the DFARS provision 252.204-7004, Alternate A, System for Award Management (SAM), and the associated provision prescription at DFARS 204.1105. The DFARS provision

provided definitions that are to be substituted for the definitions in paragraph (a) of the FAR provision 52.204-7, System for Award Management. The FAR provision is prescribed for use in most solicitations. The purpose of the FAR provision is to inform offerors of the requirement to be registered in SAM in order to be eligible for an award. The DFARS provision was created for use in DoD solicitations, to ensure, in part, that offerors responding to DoD solicitations understood that they needed to enter a CAGE code in SAM in order to be considered registered in the system. However, the DFARS provision is no longer necessary, because the definition of "Registered in the System for Award Management (SAM) database" in paragraph (a) of the FAR provision has been updated to include a CAGE code as part of the information required from an offeror in order to be considered registered in SAM. As such, this DFARS alternate provision is redundant and can be removed. The removal of this DFARS text supports a recommendation from the DoD Regulatory Reform Task Force. On February 24, 2017, the President signed Executive Order (E.O.) 13777, "Enforcing the Regulatory Reform Agenda," which established a Federal policy "to alleviate unnecessary regulatory burdens" on the American people. In accordance with E.O. 13777

From the NIST SP 800-172 Rev 3 Final Public Draft: Integrity-checking mechanisms including parity checks, cyclical 2097 redundancy checks, cryptographic hashes, and associated tools can automatically monitor the integrity of systems and hosted applications. There are many ways to verify software integrity throughout the system development life cycle. Root of trust mechanisms (e.g., secure boot, trusted platform modules, UEFI) verify that only trusted code is executed during boot processes. The employment of cryptographic signatures ensures the integrity and authenticity of critical software that stores, processes, or transmits, CUI. This requirement is sourced to a control tailored out of the SP 800-53B [13] moderate baseline in SP 800-171. P
ROTECTION STRATEGY PRA, DLO ADVERSARY EFFECTS Preclude (Preempt), Expose (Detect) R

3.4.1 Current automated information systems capable of representing multiple levels of confidentiality sensitivity only support a monolithic model described in terms of ordered hierarchical levels and additional non-hierarchical categories.

- o Timeline analysis of log data, including synchronization of timestamps 4. Anti-forensics (e.g., obfuscation, data hiding, malware). Anti-forensics is a set of techniques used specifically to prevent or mislead forensic analysis. Anti-forensic challenges in cloud forensics include: - o The use of obfuscation, malware, data hiding, or other techniques to compromise the integrity of evidence - o Malware may circumvent virtual machine isolation methods 5. Incident first responders (e.g., trustworthiness of cloud providers, response time, reconstruction). Incident first responder challenges in cloud forensics include: - o Confidence, competence, and trustworthiness of the cloud providers to act as first responders and perform data collection - o Difficulty in performing initial triage - o Processing a large volume of collected forensic artifacts 6. Role management (e.g., data owners, identity management, users, access control). Role management challenges in cloud forensics include: - o Uniquely identifying the owner of an account - o Decoupling between cloud user credentials and physical users - o Ease of anonymity and creating fictitious identities online - o Determining exact ownership of data - o Authentication and access control 7. Legal (e.g., jurisdictions, laws, service-level agreements, contracts, subpoenas, international cooperation, privacy, ethics). Legal challenges in cloud forensics include: - o Identifying and addressing issues of jurisdictions for legal access to data - o Lack of effective channels for international communication and cooperation during an investigation - o Data acquisition that relies on the cooperation, competence, and trustworthiness of cloud providers - o Missing terms in contracts and service-level agreements - o Issuing subpoenas without knowledge of the physical location of data 8. Standards (e.g., standard operating procedures, interoperability, testing, validation).

Control OS-1100: or reviewing system security is also provided. We recommend that auditors attend the Information Systems Workshop or EDP Audit Workshop seminars, or their equivalents, prior to attending this session. ## DECNET COURSE TITLE: Auditing Decnet COURSE LENGTH: 2 DAY ## VENDOR: Canaudit Inc. P.O. Box 4150 Simi Valley, CA 93093 (805) 583-3723 Many Canaudit clients use the DEC VAX as an integral part of extensive network applications. It is essential that these applications be secure and that communications be safe and confidential, this seminar is specifically designed for Canaudit clients using DECnet, the primary communications architecture for Digital networks. Complete coverage of all aspects of DECnet security including network implementations. Network Control Program and network access control methodologies is included in this concentrated seminar. All participants will learn the critical control features of DECnet and how to evaluate the control

structure. In addition they will receive complete audit programs and utilities to automate much of the audit. NOTE: AUDITING VAX: A COMPREHENSIVE APPROACH is the prerequisite for this course. VAX COURSE TITLE: Auditing VAX: A Comprehensive Approach COURSE LENGTH: 3 DAY VENDOR: Canaudit Inc. P.O. Box 4150 Simi Valley, CA 93093 (805) 583-3723 This session is the most comprehensive VAX Audit course currently available. It is intended for auditors who will be auditing the VAX operating system and its components. The seminar provides participants with an understanding of the hardware, software and security requirements as well as depth, along with detailed descriptions of utilities and System Generation controls. Because of the popularity of this topic, we recommend early registration. NOTE: We recommend that participants attend the AUDITING ADVANCED INFORMATION TECHNOLOGY or EDP AUDIT WORKSHOP seminars or their equivalents prior to attending this course.

Based on the number of small businesses registered within the SBA Dynamic Small Business Search, the overall industrial base of federal government small businesses is 313,651. Approximately 1,000 facilities were randomly selected from the NISP to determine if the selected facilities were registered within the SBA Dynamic Small Business Search. With 95% confidence, it can be estimated that there are between 7,672 and 8,400 small entities impacted by this rule. The general methodology to determine a random sample and the estimated number of small business entities impacted by this rule is outlined in the following table. The random selection is dependent on the contractor facility having an active facility security clearance and permanent CAGE Code. NISP small entities estimate Total cleared contractor facilities enrolled in the DoD National Industrial Security System (NISS) as of May 14, 2020: 12,384 Randomly Selected facilities from the current cleared contractor population: 1,014 The proportion of cleared contractor facilities in the simple random sample enrolled in the SBA Database: $658/1,014 = 64.89\%$ Equates to 8,036 facilities as small business entities. Margin of Error for proportion enrolled in SBA database (95% confidence): $\pm 2.94\%$ Equates to ± 364 facilities cleared contractor facilities. The interval estimate for the number of small businesses in the NISP: $8,036 \pm 364 = 7,672$ to $8,400$ cleared contractor facilities. (printed page 83311) Based on the simple random sample, we can be 95% confident that the true proportion of active cleared contractor facilities enrolled in the SBA database is between 62.0% and 67.8%. Based on cleared contractor enrollment as of May 14, 2020, the percentages equate to an interval estimate between 7,672 and 8,400 small business entities which are cleared contractor facilities and impacted by this rule. Assumptions and Notes: · Facilities self-enrolled in the SBA database are, in fact, small businesses. The following link was used to determine if a facility was a small business by searching CAGE codes showing all NAICS for which a business is a small business: https://web.sba.gov/pro-net/search/dsp_dsbs.cfm . · The SBA database is generally a self-certifying database. The SBA does not make any representation as to the accuracy of any of the data included, other than certifications relating to 8(a) Business Development, HUBZone or Small Disadvantaged Business status. The SBA strongly recommends that contracting officers diligently review a bidder's small business self-certification before awarding a contract. · Facilities were selected from the active NISS population using a simple random sample (1,014 selected of 12,384 enrolled facilities). · Selection of each facility is independent of all other facilities selected ($N * .10 > n$). · The sample is large enough ($n = 1014$) that we can assume the sampling distribution of sample proportions is approximately normal ($n * p > 10$ and $n * (1-p) > 10$). Congressional Review Act

(8) No verification of identity shall be required of an individual seeking access to records that are otherwise available to the public. (9) Individuals shall not be denied access to a record in a SOR about themselves because those records are exempted from disclosure under 32 CFR part 285 . Individuals may only be denied access to a record in a SOR about themselves when those records are exempted from the access provisions of 32 CFR part 310, subpart F , and this part. (10) Individuals shall not be denied access to their records for refusing to disclose their Social Security Number (SSN), unless disclosure of the SSN is required by statute, by regulation adopted before January 1, 1975, or if the record's filing identifier and only means (printed page 24130) of retrieval is by the SSN (reference 5 U.S.C. 552a , note, Executive Order 9397). (c) Access to Records or Information Compiled for Law Enforcement Purposes. (1) All requests by individuals to access records about themselves are processed under 5 U.S.C. 552 , 5 U.S.C. 552a as well as 32 CFR part 286 , 32 CFR part 310, subpart D to give requesters a greater degree of access to records on themselves, regardless of which Act is cited by the requestor for processing. (2) Records (including those in the custody of law enforcement activities) that have been incorporated into a SOR exempted from the access conditions of 5 U.S.C. 552a and 32 CFR part 310, subpart D will be processed in accordance with 5 U.S.C. 552a , 32 CFR part 310, subpart D , and this part.

Individuals shall not be denied access to records solely because they are in an exempt system. They will have the same access that they would receive under 5 U.S.C. 552 and 32 CFR part 286 . (3) Records systems exempted from access conditions will be processed under 5 U.S.C. 552 and 32 CFR part 286 , or 5 U.S.C. 552a and 32 CFR part 310, subpart D , depending upon which gives the greater degree of access. (4) If a non-law enforcement element has temporary custody of a record otherwise exempted from access under 32 CFR part 310, subpart F for the purpose of adjudication or personnel actions, they shall refer any such access request, along with the records, to the originating agency and notify the requestor of the referral. (d) Access to Illegible, Incomplete, or Partially Exempt Records. (1) An individual shall not be denied access to his or her record or a copy of the record solely because the physical condition or the format of the record does not make it readily available (e.g. record is in a deteriorated state or on a magnetic tape). The document will be prepared as an extract, or it will be exactly recopied. (2) If a portion of the record contains information that is exempt from access, an extract or summary containing all of the information in the record that is releasable shall be prepared by the System Manager. (3) When the physical condition of the record makes it necessary to prepare an extract for release, the extract shall be prepared so that the requestor will understand it.

of the Privacy Act of 1974, as amended, was submitted on January 29, 2004, to the House Committee on Government Reform, the Senate Committee on Governmental Affairs, and the Office of Management and Budget (OMB) pursuant to paragraph 4c of Appendix I to OMB Circular No. A-130, 'Federal Agency Responsibilities for Maintaining Records About Individuals,' dated February 8, 1996 (February 20, 1996, 61 FR 6427). Dated: February 2, 2004. John Miller, Alternate OSD Federal Register Liaison Officer, Department of Defense. S253.10 DLA-G System name: Invention Disclosure (February 22, 1993, 58 FR 10854). Changes: * * * * * System identifier: Replace 'S253.10 DLA-G' with 'S100.70'. * * * * * Categories of individuals covered by the system: Delete 'to the DLA General Counsel' at the end of the sentence and replace with 'to DLA'. * * * * * Categories of records in the system: Delete entry and replace with 'Inventor's name, Social Security Number, address, and telephone numbers; descriptions of inventions; designs or drawings, as appropriate; evaluations of patentability; recommendations for employee awards; licensing documents; and similar records. Where patent protection is pursued by DLA, the file may also contain copies of applications, Letters Patent, and related materials.' * * * * * Authority for maintenance of the system: Delete entry and replace with ' 5 U.S.C. 301 , Departmental Regulations; 5 U.S.C. 4502 , General provisions; 10 U.S.C. 2320 , Rights in technical data; 15 U.S.C. 3710b , Rewards for scientific, engineering, and technical personnel of federal agencies; 15 U.S.C. 3711d , Employee activities; 35 U.S.C. 181-185 , Secrecy of Certain Inventions and Filing Applications in Foreign Countries; E.O. 9397 (SSN); and E.O. 10096 (Inventions Made by Government Employees) as amended by E.O. 10930 .' * * * * * Purpose(s): Delete entry and replace with 'Data is maintained for making determinations regarding and recording DLA interest in the acquisition of patents; for documenting the patent process; and for documenting any rights of the inventor. The records may also be used in conjunction with the employee award program, where appropriate.' * * * * * Routine uses of records maintained in the system, including categories of users and the purpose of such uses: Add two new paragraphs: 'To the U.S. Patent and Trademark Office for use in processing applications and performing related functions and responsibilities under Title 35 of the U.S. Code. To foreign government patent offices for the purpose of securing foreign patent rights.' * * * * * Safeguards: Delete entry and replace with 'Access is limited to those individuals who require the records for the performance of their official duties. Paper records are maintained in buildings with controlled or monitored access. During non-duty hours, records are secured in locked or guarded buildings, locked offices, or guarded cabinets. The electronic records systems employ user identification and password or smart card technology protocols.' * * * * *

Retention and disposal:

The Department is committed to overseeing the CMMC Program and will take appropriate measures to ensure its efficient execution. Presently, the Department has no intention of mandating that contracting offices adopt presumptive measures that would reduce the number of small contracts subject to Level 2 certification assessment, nor does it plan to impose affirmative requirements on prime contracts to utilize enclaves. Prior to conduct of an assessment, the OSC engages with the C3PAO assessor. It is during this time that classification of assets should be established, and the results of these discussions documented in pre-planning materials. This is an example of the pre-assessment and planning material submitted by the C3PAO as required in §170.9(b)(8) and the CMMC Assessment Scope submitted to eMASS as required in §170.17(a)(1)(i)(D). The DoD considered the NIST

definitions for System Information and Security Relevant Information in the development of the CMMC definition for SPD. This rule does not regulate an OSA's SPD, but instead implements existing regulatory requirements for the safeguarding of CUI, as defined in 32 CFR 2002.14(h)(2) and implemented by DFARS clause 252.204-7012. The DFARS clause 252.204-7012 requires protection of security protection assets and security protection data through its specification of NIST SP 800-171. Section 1.1 of NIST SP 800-171 R2 states: "The requirements apply only to components of nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components." There is therefore no increase in the scope as described in the rule, and no revisions to cost estimates are required. The DoD received numerous comments about the requirements for CMMC when an ESP is used. In response to these comments, the DoD revised the rule to reduce the assessment burden on External Service Providers (ESPs) by updating the ESP assessment, certification, and authorization requirements in §§ 170.19(c)(2) and (d)(2). The use of an ESP, its relationship to the OSA, and the services provided need to be documented in the OSA's System Security Plan and described in the ESP's service description and customer responsibility matrix (CRM), which describes the responsibilities of the OSA and ESP with respect to the services provided. An ESP is considered a Cloud Service Provider (CSP) when it provides its own cloud services based on a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing that can be rapidly provisioned and released with minimal management effort or service provider interaction on the part of the OSA. ESPs that are CSPs, and process, store, or transmit CUI, must meet the FedRAMP requirements in DFARS clause 252.204-7012. ESPs that are CSPs and do not process, store, or transmit CUI, are not required to meet FedRAMP requirements in DFARS clause 252.204-7012.

| FAMILY | FAMILY | |-----|-----|
 Access Control | Media Protection | | Awareness and Training | Personnel Security | | Audit and Accountability | Physical Protection | | Configuration Management | Risk Assessment | | Identification and Authentication | Security Assessment | | Incident Response | System and Communications Protection | | Maintenance | System and Information Integrity | 17 The Audit and Accountability, Maintenance, Media Protection, and Physical Protection families do not contain enhanced security requirements at this time. ## 3.8 MEDIA PROTECTION

addresses the implementation of procedures for terminating a workforce member's access to ePHI when their employment or similar arrangement ends or as required by the regulated entity's workforce clearance procedures. Under 45 CFR 164.308(a)(4)(i), the standard for information access management, a regulated entity is required to implement policies and procedures for authorizing access to ePHI in a manner that is consistent with the requirements of the Privacy Rule, that is, only when such access is appropriate based on the user or recipient's role (i.e., "role-based access"). This interpretation is consistent with the Privacy Rule's standard that limits most uses and disclosures of PHI to the "minimum necessary" to accomplish the purpose of the use or disclosure. [434] The standard for information access management has three implementation specifications: paragraph (a)(4)(ii)(A) requires a health care clearinghouse that is part of a larger organization to implement policies and procedures to protect ePHI from unauthorized access by that organization; paragraph (a)(4)(ii)(B) addresses implementation of policies and procedures for granting access to ePHI, for example, through a workstation, program, or other mechanism; and paragraph (a)(4)(ii)(C) addresses the implementation of policies and procedures that, based on the regulated entity's access authorization policies, establish, document, review, and modify a user's right of access to a workstation, program, or other process. Section 164.308(a)(5)(i) contains the standard for security awareness and training. This standard requires a regulated entity to implement a security awareness and training program for all workforce members, including management. There are four associated implementation specifications that address the need for regulated entities to implement the following: Periodic security updates. [435] Procedures for guarding against, detecting, and reporting malicious software. [436] Procedures for monitoring log-in attempts and reporting discrepancies. [437] Procedures for creating, changing, and safeguarding passwords. [438] The standard for security incident procedures at 45 CFR 164.308(a)(6)(i) requires a regulated entity to implement policies and procedures to address security incidents. The one implementation specification associated with this standard, 45 CFR 164.308(a)(6)(ii), requires regulated entities to identify and respond to suspected or known security incidents; to mitigate, to the extent practicable, harmful effects of security incidents that are known to the regulated entity; and to document security incidents and their outcomes. Under the standard for contingency planning at 45 CFR 164.308(a)(7)(i), a regulated entity is required to establish, and

implement as needed, policies and procedures for responding to an emergency or other occurrence that damages systems that contain ePHI. The standard includes five implementation specifications at 45 CFR 164.308(a)(7)(ii)

To address this recurring problem, this rule establishes and standardizes a process to enable offerors to propose changes in their offer to the solicitation's line item structure. Establishing such a process is a first step towards managing variation in these transactions by eliminating or reducing manual intervention. II. Executive Orders 12866 and 13563 Executive Orders (E.O.s) 12866 and 13563 direct agencies to assess all costs and benefits of available regulatory alternatives and, if regulation is necessary, to select regulatory approaches that maximize net benefits (including potential economic, environmental, public health and safety effects, distributive impacts, and equity). E.O. 13563 emphasizes the importance of quantifying both costs and benefits, of reducing costs, of harmonizing rules, and of promoting flexibility. This is not a significant regulatory action and, therefore, was not subject to review under section 6(b) of E.O. 12866, Regulatory Planning and Review, dated September 30, 1993. This rule is not a major rule under 5 U.S.C. 804. III. Regulatory Flexibility Act DoD certifies that this final rule will not have a significant economic impact on a substantial number of small entities within the meaning of the Regulatory Flexibility Act, 5 U.S.C. 601, et seq., because the rule does not impose any additional requirements on small businesses. Further, this change does not add to, or delete from existing requirements or authorities for entities to include alternative line item structures in their offers. This rule is formalizing a process to facilitate offerors' ability to request changes to the line item structure. IV. Paperwork Reduction Act The rule does not contain any information collection requirements that require the approval of the Office of Management and Budget under the Paperwork Reduction Act (44 U.S.C. chapter 35). (printed page 58139) List of Subjects in 48 CFR Parts 204, 212, and 252 Government procurement Mary Overstreet, Editor, Defense Acquisition Regulations System. Therefore, 48 CFR parts 204, 212, and 252 are amended as follows: 1. The authority citation for 48 CFR parts 204, 212, and 252 continues to read as follows: Authority: 41 U.S.C. 1303 and 48 CFR chapter 1. PART 204-ADMINISTRATIVE MATTERS 2. Amend section 204.7103 by adding a new paragraph (g) to read as follows: 204.7103-1 Criteria for establishing. * * * * *

(2)(i) If the Contractor's accounting system is not capable of identifying and tracking through the build cycle the property that is allocable and properly chargeable to this contract, the Contracting Officer may consider acceptance of one or a combination of the following alternative forms of security sufficient to constitute adequate security for the performance-based payments and so specify in the contract, consistent with FAR 32.202-4: (A) A paramount lien on assets. (B) An irrevocable letter of credit from a federally insured financial institution. (C) A bond from a surety, acceptable in accordance with FAR part 28. (D) A guarantee of repayment from a person or corporation of demonstrated (printed page 19691) liquid net worth, connected by significant ownership interest to the Contractor. (E) Title to identified Contractor assets of adequate worth. (ii) Paragraph (f) of the clause at FAR 52.232-32 does not apply to the extent that the Contractor and the Contracting Officer agree on alternative forms of security. In the event the Contractor fails to provide adequate security, as required in this contract, no financing payment will be made under this contract. Upon receipt of adequate security, financing payments will be made, including all previous payments to which the Contractor is entitled, in accordance with the terms of the provisions for contract financing. If at any time the Contracting Officer determines that the security provided by the Contractor is insufficient, the Contractor shall promptly provide such additional security as the Contracting Officer determines necessary. In the event the Contractor fails to provide such additional security, the Contracting Officer may collect or liquidate such security that has been provided and suspend further payments to the Contractor; and the Contractor shall repay to the Government the amount of unliquidated financing payments as the Contracting Officer at his sole discretion deems repayable. 12. Add section 252.232-7015 to read as follows: 252.232-7015 Performance-Based Payments-Representation As prescribed in 232.1005-70(b), use the following provision: Performance-Based Payments-Representation (APR 2020) (a) In accordance with 10 U.S.C. 2307(b)(4)(A), the Contractor's financial statements shall be in compliance with Generally Accepted Accounting Principles in order to receive performance-based payments. (b) The Offeror represents that its financial statements are [.] are not [.] in compliance with Generally Accepted Accounting Principles. (End of provision) 13. Add section 252.232-7016 to read as follows: 252.232-7016 Notice of Progress Payments or Performance-Based Payments As prescribed in 232.1005-70(c), insert the following provision: Notice of Progress Payments or Performance-Based

(Comment 27) One comment seeks clarification regarding application of the recordkeeping requirements to certain ownership-partnership relationships involving a U.S. trucking company and a Canadian or Mexican trucking company. The comment asks, for example, whether a Canadian subsidiary of a U.S. trucking company is subject to the recordkeeping requirements. The comment states that a Canadian trucking company may be in partnership with a U.S. company, and the percentage of U.S. ownership is established in each partnership. Another example provided by the comment is that a Mexican motor carrier may have a contractual or interline relationship with a U.S. company. The comment asks whether the recordkeeping requirements apply to the foreign transporters with these U.S. relationships. (Response) The final rule applies to persons who manufacture, process, pack, transport, distribute, receive, hold, or import food in the United States. Thus, any person who transports food in the United States is subject to these recordkeeping requirements with respect to that food that enters the United States. The partnership or contractual status with a U.S. company does not affect the application of these requirements to a foreign person if they are transporting food in the United States, because such persons are already covered by this final rule by virtue of transporting food in the United States. (Comment 28) One comment seeks clarification on whether residency in a territory of the United States affects applicability of the regulation. One comment questions FDA's authority to apply the proposed regulation to the Caribbean jurisdictions of the U.S. Virgin Islands and the Commonwealth of Puerto Rico. The comment contends that the regulations would be burdensome to grocery operators or other retailers in the Caribbean jurisdictions who do not export to the Continental United States, but would not deter bioterrorism acts in the Continental United States or in the Caribbean jurisdictions. The comment asserts that the proposed regulation will jeopardize the island economies of the Caribbean jurisdictions by increasing unnecessary expenses to the food retailing activity, which is already more expensive than in the Continental United States, by adding, among other expenses, the maritime transportation cost to the goods.

In recognition of those potential harms and the health care sector's importance to the economy and security of the U.S., the President has designated 'Healthcare and Public Health' as a critical infrastructure sector [11] and the Department as the Sector Risk Management Agency (SRMA). [12] In addition, to address concerns about the increasing level of cybercrime, the President has charged Federal agencies with 'establishing and implementing minimum requirements for risk management' and robustly enforcing those requirements and Federal laws to help manage that risk. [13] We believe that a comprehensive and updated Security Rule is critical to accomplishing these directives and to the Department's effectiveness as the SRMA for the Healthcare and Public Health sector. In further recognition of these concerns, States have promulgated or are in the process of promulgating regulations that would require the adoption of certain standards or measures for the protection of sensitive information, such as PHI. [14] While these proposed regulations may contain helpful guidance for regulated entities, none specifically focus on ensuring the security of ePHI and the information systems that create, receive, maintain, or transmit ePHI. Additionally, a patchwork of State-specific laws may create difficulties for regulated entities that are located or operate in multiple States. Several entities, including Federal agencies, have published and maintained guidelines, best practices, methodologies, procedures, and processes for protecting the security of sensitive information, including PHI. Some examples of these resources include the National Institute of Standards and Technology's (NIST's) 'Cybersecurity Framework,' [15] the HHS 405(d) Program's 'Health Industry Cybersecurity Practices: Managing Threats and Protecting Patients,' [16] the Federal Trade Commission's (FTC's) 'Start with Security: A Guide for Business,' [17] and the Department's 'Cybersecurity Performance Goals' (CPGs). [18] We believe that the proliferation of such documents in recent years has been helpful, and we have considered them in the development of this NPRM. However, in light of the increasing number and sophistication of cybersecurity incidents, we do not believe that these documents are sufficiently instructive for regulated entities to help improve their compliance with the Security Rule. Under its statutory authority to administer and enforce the HIPAA Rules, the Department modifies the HIPAA Rules as needed, but does not modify a standard or implementation specification more than once every 12 months. [19]

. However, if an individual is denied any right, privilege, or benefit for which he would otherwise be entitled by Federal law, as a result of the maintenance of the information, the individual will be provided access to the information except to the extent that disclosure would reveal the identity

of a confidential source. Note 1 to paragraph (f)(22)(i). When claimed, this exemption allows limited protection of investigative reports maintained in a system of records used in personnel or administrative actions. Any portion of this system of records which falls within the provisions of 5 U.S.C. 552a(k)(2) may be exempt from the following subsections of 5 U.S.C. 552a(c)(3) , (d), (e)(1), (e)(4)(G), (H), and (I), and (f). (ii) Authority. 5 U.S.C. 552a(k)(2) . (iii) Reasons. (A) From subsection (c)(3) because to grant access to the accounting for each disclosure as required by the Privacy Act, including the date, nature, and purpose of each disclosure and the identity of the recipient, could alert the subject to the existence of the investigation. This could seriously compromise case preparation by prematurely revealing its existence and nature; compromise or interfere with witnesses or make witnesses reluctant to cooperate; and lead to suppression, alteration, or destruction of evidence. (B) From subsections (d) and (f) because providing access to investigative records and the right to contest the contents of those records and force changes to be made to the information contained therein would seriously interfere with and thwart the orderly and unbiased conduct of the investigation and impede case preparation. Providing access rights normally afforded under the Privacy Act would provide the subject with valuable information that would allow interference with or compromise of witnesses or render witnesses reluctant to cooperate; lead to suppression, alteration, or destruction of evidence; enable individuals to conceal their wrongdoing or mislead the course of the investigation; and result in the secreting of or other disposition of assets that would make them difficult or impossible to reach in order to satisfy any Government claim growing out of the investigation or proceeding. (C) From subsection (e)(1) because it is not always possible to detect the relevance or necessity of each piece of information in the early stages of an investigation. In some cases, it is only after the information is evaluated in light of other evidence that its relevance and necessity will be clear. (D) From subsections (e)(4)(G) and (H) because this system of records is compiled for investigative purposes and is exempt from the access provisions of subsections (d) and (f).

The records redesign burden presented in table 25 of this document reflects the burden that some firms will incur by adding a limited amount of new information to their records. Some firms will not already be keeping the required information in a readily accessible form. The records redesign burden includes labor and capital costs associated with modifying existing forms so that they are better suited to meet the recordkeeping requirements. This is assumed to be a one-time burden incurred by each covered firm in the first and second years following implementation of the final rule. FDA expects that personnel at most facilities will incur a records maintenance burden due to collecting, recording, and checking for accuracy the limited amount of additional information required by the proposed rule. The burden from this activity is reported in table 25 of this document and is assumed to be incurred by all facilities in each subsequent year following enactment of the final rule. Finally, new firms are assumed to incur burdens from learning in each subsequent year following enactment of the final rule. These burdens for new (printed page 71650) firms are reported in table 26 of this document.

Table 25. Estimated Annual Recordkeeping Burden-First and Second Years			
21 CFR Section	No. of Record keepers	Annual Frequency per Record	Total Annual Records
1.337, 1.345, and 1.352 (learning)	707,672	4.790	3,390,000
1.337, 1.345, and 1.352 (redesign)	150,358	1	150,358
Total	7,763,000	1	7,763,000

There are no operating and maintenance costs associated with this collection of information.

Table 26. Estimated Annual Recordkeeping Burden-Subsequent Years			
21 CFR Section	No. of Record Keepers	Annual Frequency per Record	Total Annual Records
1.337, 1.345, and 1.352 (additional records maintenance)	379,493	13.228	5,020,000
1.337, 1.345, and 1.352 (learning for new firms)	70,767	4.790	339,000
Total	5,359,000	1	5,359,000

There are no capital costs or operating and maintenance costs associated with this collection of information. The information collection provisions of this final rule have been submitted to OMB for review. Before the effective date of this final rule, FDA will publish a notice in the Federal Register announcing OMB's decision to approve, modify, or disapprove the information collection provisions in this final rule. An agency may not conduct or sponsor, and a person is not required to respond to, a collection of information unless it displays a currently valid OMB control number.

IX. Analysis of Environmental Impact The agency has carefully considered the potential environmental effects of this action. FDA has concluded under 21 CFR 25.30(h) that this action is of a type that does not individually or cumulatively have a significant effect on the human environment. Therefore, neither an environmental assessment nor an environmental impact statement is required.

X. Federalism

Some of the public safety mobile application security requirements may be addressed using techniques

after the application is deployed. The following are a few examples of these techniques: mobile device profile management, mobile application whitelisting, scanning the mobile device for installed malware, and network security. Since these techniques are highly dependent on the mobile application's operating environment and outside the control of the mobile application developer, these techniques were considered outside the scope of this workshop. 1. Apps are just like any software and are vulnerable to commonly known risks of infection, malware, and other cyber threats.

From the NIST SP 800-172 Rev 3 Final Public Draft: This publication incorporates the following changes from the original edition (February 2, 2021):

- Streamlined introductory information in Sec. 1 and Sec. 2 to improve clarity and understanding
- Increased the specificity of the enhanced security requirements to remove ambiguity, improve the effectiveness of implementation, and clarify the scope of assessments
- Grouped enhanced security requirements, where possible, to improve understanding and the efficiency of implementations and assessments
- Removed outdated and redundant enhanced security requirements
- Added new enhanced security requirements based on (1) the latest threat intelligence, (2) empirical data from cyber-attacks, and (3) the expansion of security objectives to include integrity and availability
- Added titles to the

ations prevailed. An important characteristic of a forensic tool is its ability to maintain the integrity of the original data source being acquired and also that of the extracted data. The former is done by blocking or otherwise eliminating write requests to the device containing the data. The latter is done by computing a cryptographic hash over the contents of the evidence files created and recurrently verifying that this value remains unchanged throughout the lifetime of those files. Preserving integrity not only maintains credibility from a legal perspective, but it also allows any subsequent investigation to use the same baseline for replicating the analysis.

SP 800-53 Revision 4 has been updated to reflect the evolving technology and threat space. Example areas include issues particular to mobile and cloud computing; insider threats; applications security; supply chain risks; advanced persistent threat; and trustworthiness, assurance, and resilience of information systems. The revision also contains a new appendix of privacy controls, and related implementation guidance (Appendix J), based on the Fair Information Practice Principles (FIPPs), a widely accepted framework of defining principles to be used in the evaluation and consideration of systems, processes, or programs that affect individual privacy. Many organizations use well-known international information security standards as the basis or as a supplemental source of security controls for risk management. To aid in selection and comparison, SP 800-53 Rev. 4 provides mapping tables to provide organizations with a general indication of security control coverage with respect to ISO/IEC 27001, Information technology Security techniques-Information security management systems-Requirements and ISO/IEC 15408, Information technology -- Security techniques -- Evaluation criteria for IT security . ISO/IEC 27001 applies to all types of organizations and specifies requirements for establishing, implementing, operating, monitoring, reviewing, maintaining, and improving a documented information security management system (ISMS) within the context of business risks. ISO/IEC 15408 (also known as the Common Criteria) provides functionality and assurance requirements for developers of information systems and information system components (i.e., information technology products).

As NIST states in NIST SP 800-171A Jun2018,

- The assessment procedures are flexible and can be customized to the needs of the organizations and the assessors conducting the assessments. Security assessments can be conducted as self-assessments; independent, third-party assessments; or government-sponsored assessments and can be applied with various degrees of rigor, based on customer-defined depth and coverage attributes.
- CMMC Program requirements are designed to ensure compliance with existing standards for protection of FCI and CUI and align directly to NIST guidelines (i.e., NIST SP 800-171 R2 and NIST SP 800-172 Feb2021) and the basic safeguarding requirements (of FAR clause 52.204-21) that apply to all executive agencies. The rule accounts for costs associated with assessment via NIST SP 800-171A Jun2018. Within the limitations of section §170.21 Plan of Action and Milestones Requirements, offerors may bid on a contract while continuing to work towards full CMMC compliance. DoD rejects the notion that organizations must accelerate to meet a requirement in place since 2017. DoD did not intend nor expect that POA&Ms would remain open-ended and unimplemented for years. The DoD provided an analysis of costs to meet CMMC Level 1 and 2 requirements in the regulatory impact analysis for this rule. Certification is never required for CMMC Level 1, which is a self-assessment requirement. CMMC Level 2 may either be met via self-assessment, or via a C3PAO assessment, depending on the specific requirement cited in the

solicitation. It is not within in scope of this rule to address the way companies recover assessment costs. Verifying compliance with applicable security requirements may increase cost and is necessary for the protection of DoD FCI and CUI. The cost of lost technological advantage over potential adversaries is greater than the costs of such enforcement. 29. CMMC Benefits and Cost Estimates a. Cost Estimate Assumptions Comment: Some comments proposed the DoD directly assume the costs for industrial base compliance, increase contract award prices, offer grants and loans, or provide tax credits to offset the costs associated with compliance. One asked for clarification regarding allowable versus unallowable costs. One comment stated the cost estimate was a good guesstimate of the total cost to the USG, but the flow down costs and the price of doing business will be at the Program Office level. The commenter requested the DoD provide a table of Program Office funding requirements to aid Program Managers in reflecting CMMC costs in an Acquisition Strategy and Cost Analysis Requirements Document (CARD).

(3) Furnish copies of the statement of disagreement to all DoD Components and Federal agencies that have been provided copies of the disputed information and who may be maintaining the information.

(n) Maintaining statements of disagreement. (1) When possible, incorporate the statement of disagreement into the record. (2) If the statement cannot be made a part of the record, establish procedures to ensure that it is apparent from the records a statement of disagreement has been filed and maintain the statement so that it can be obtained readily when the disputed information is used or disclosed. (3) Automated record systems that are not programmed to accept statements of disagreement shall be annotated or coded so they clearly indicate that a statement of disagreement is on file, and clearly identify the statement with the disputed information in the system. (4)

Provide a copy of the statement of disagreement whenever the disputed information is disclosed for any purpose. (o) The DoD Component statement of reasons for refusing to amend. (1) A statement of reasons for refusing to amend may be included with any record for which a statement of disagreement is filed. (2) Include in this statement only the reasons furnished to the individual for not amending the record. Do not comment on or respond to comments contained in the statement of disagreement. Normally, both statements are filed together. (3) When disclosing information for which a statement of reasons has been filed, a copy of the statement may be released whenever the record and the statement of disagreement are disclosed. (p) Privacy case files. (1) Establish a separate Privacy case file to retain the documentation received and generated during the amendment or access process. (2) The Privacy case file shall contain as a minimum: (i) The request for amendment and access. (ii) Copies of the DoD Component's reply granting or denying the request; (iii) Any appeals from the individual; (iv) Copies of the action regarding the appeal with supporting documentation that is not in the basic file; and (v) Any other correspondence generated in processing the appeal, to include coordination documentation. (3) Only the items listed in paragraphs (p)(4) and (p)(5) of this section may be included in the system of records challenged for amendment or for which access is sought. Do not retain copies of the original record in the basic record system if the request for amendment is granted and the record has been amended. (4) The following items relating to an amendment request may be included in the disputed record system: (i) Copies of the amended record. (ii) Copies of the individual's statement of disagreement (see paragraph (m) of this section). (iii) Copies of the Component's statement of reasons for refusing to amend (see paragraph (o) of this section). (iv) Supporting documentation submitted by the individual. (5) The following items relating to an access request may be included in the basic records system:

(Comment 78) Some comments state that these proposed regulations would require a substantial and costly change in the way meals are delivered and processed. The comments urge FDA to consider whether the air and rail industries can bear the additional expense of these proposed regulations, as numerous ingredients are included in each meal that is prepared and boarded. The comments state that compliance with the traceability regulations depicted in the rule would require so many revamped processes and additional personnel that their organizations would likely not recover from the fiscal implications. The comments further state that they would have to completely change the way they produce and package meals for their customers, going to unprecedented lengths to ensure strict batch preparation. As an example, the comments note that with their current processes, they can determine shipment origin and location of the entire meal; however, it would be impossible to trace each individual ingredient going into the package. For example, meat from one lot number of ham could be put into sandwiches along with other ingredients from different sources and fruit or chips, and then loaded onto numerous flights. This level of batch control would make the production of these sandwiches and meals cost prohibitive. The comments further state that the impact on the

airline industry from September 11, 2001, has been tremendous. The airline industry is facing unprecedented challenges, and the way business is conducted has been altered forever. The comments note that reductions and bankruptcy filings by the various airlines have been extreme and have resulted in immense reductions in the airline catering business. The airlines' decisions to significantly cut back, eliminate food service, and reduce the load capacity on airplanes and number of flights continue to impact the interstate conveyance catering business. The comments urge FDA to consider these conditions because it will be difficult for the airline catering business to absorb the costs of proposed regulations into its current pricing structure. The comments conclude that they would be forced to pass these costs onto the already struggling airline industry.

The Defense Industrial Base Cybersecurity Assessment Center (DIBCAC) is the sole entity within the Department of Defense entrusted with conducting cybersecurity assessments of defense contractor information systems. DIBCAC operates under the Defense Contract Management Agency (DCMA) and is responsible for Medium and High assessments under DFARS 252.204-7020 and government-led CMMC Level 3 assessments. In FY2026, DCMA is establishing four functional teams with approximately 18 additional FTEs to perform 75 additional cybersecurity assessments.

156. On July 29, 2024, the Department announced that the Office of the National Coordinator for Health Information Technology was being renamed the Assistant Secretary for Technology Policy and Office of the National Coordinator for Health Information Technology. In this NPRM, we continue to use ONC for publications cited that predate the renaming of that office. 89 FR 60903 (July 29, 2024). Back to Citation 157. See, e.g., 45 CFR 170.315(d)(6), (7), (12), and (13).

For more information on the ONC Health IT Certification Program, visit

<https://www.healthit.gov/-topic/-certification-ehrs/-certification-health-it>. Back to Citation

158. The ONC Health IT Certification Program specifies at 45 CFR 170.550(h) the privacy and security certification framework for Health IT Modules. Section 170.550(h) identifies a mandatory minimum set of the certification criteria that ONC-Authorized Certification Bodies (ONC ACBs) must ensure are also included as part of specific Health IT Modules that are presented for certification.

See Certification Companion Guide Privacy and Security, The Office of the National Coordinator for Health Information Technology, U.S. Department of Health and Human Services (May 7, 2024), https://www.healthit.gov/-sites/-default/-files/-2015Ed_-CCG_-Privacy_-and_-Security.pdf. Back to Citation

159. See 45 CFR 171.102 (definition of Electronic health information). Back to Citation 160. See, e.g., Medicare Promoting Interoperability Program, 42 CFR 495.24 (eligible hospitals and critical access hospitals must use certified electronic health record technology (CEHRT), with limited exceptions, to comply with the program's meaningful use requirements); Merit-based Incentive Payment System (MIPS) Promoting Interoperability performance category, 42 CFR 414.1375 (requiring MIPS eligible clinicians to use CEHRT, as defined in 42 CFR 414.1305, to comply with reporting requirements for the Promoting Interoperability performance category). Back to Citation

161. See, e.g., Health Industry Cybersecurity Practices: Managing Threats and

Protecting Patients, supra note 16. Back to Citation 162. See, e.g., The NIST Cybersecurity

Framework (CSF) 2.0, supra note 15. Back to Citation 163. See, e.g., Cybersecurity

Performance Goals, supra note 18. Back to Citation 164. See, e.g., Cross-Sector Cybersecurity Performance Goals, Cybersecurity & Infrastructure Security Agency, U.S. Department of Homeland Security (Mar. 2023),

https://www.cisa.gov/-sites/-default/-files/-2023-03/-CISA_-CPG_-REPORT_-v1.0.1_-FINAL.pdf. Back

to Citation 165. See generally 45 CFR 164.308(a); The NIST Cybersecurity Framework (CSF) 2.0,

supra note 15; Cybersecurity Performance Goals, supra note 18. Back to Citation 166.

Derrick Tin, et al., Cyberthreats: A primer for health care professionals, The American Journal of Emergency Medicine, p. 182-183 (Apr. 2023), <https://doi.org/10.1016/j.ajem.2023.04.001>. Back to Citation

167. See Public Law 104-191, 110 Stat. 2021 (Aug. 21, 1996) (codified at

- Organizing constructs in Revision 1 have been simplified by deprecating Categories (e.g., securely provision, oversee and govern, protect and defend, analyze, etc.) and Specialty Areas (e.g., incident response, threat analysis, cybersecurity management, etc.). In order to simplify an approach that offers agility, flexibility, interoperability, and modularity for organizations, Revision 1 presents a streamlined set of 'building blocks' comprised of Tasks, Knowledge, and Skills. Organizations that find value in the former Categories and Specialty Areas can continue to use them or create teams around those concepts and align them with this version of the NICE Framework (see Section 3.4). - Revision 1 describes several uses of Tasks, Knowledge, and Skills, including methods of applying those in the creation of Work Roles. Users of the Work Roles described

in the original NIST SP 800-181 may continue to use those; updates to those may be published by NICE in the future. [2] The relationships among Tasks, Knowledge, Skills, and Abilities have changed. Skill and Ability statements from the previous version have been refactored for simplicity into Skill statements, which focus on the action of the learner. This revision describes methods for associating Knowledge and Skill statements with Task statements for various outcomes. The lists of Tasks, Knowledge, Skills, and Work Roles that were previously available in Appendices A and B of the 2017 Framework have been removed from this version in order to simplify the maintenance of the NICE Framework and to ease updates to those lists. The Task, Knowledge, and Skills (TKS) statements and corresponding Competencies and Work Roles will be maintained as separate artifacts and will be subject to ongoing review and updates with a defined change process and indication of version control to manage and communicate changes.

- A built-in infrastructure for (a) providing service identities, (b) service discovery, and (c) external policy-based authorization engines in which policies incorporate contextual variables. Policies pertain to service-to-service and user-to-resource authentications and authorizations and ensure application integrity and confidentiality. These policies generally are expressed through a structure called access control. Some examples of access control models include: Next Generation Access Control (NGAC) model, and Attribute-based access control (ABAC) model. - Code for performing network-related functions (e.g., traffic routing) and for ensuring network resiliency through functions such as retries, timeouts, blue-green deployments, and circuit breaking. - More details on the container orchestration platform with an integrated service mesh can be found in [2], and an access control implementation in that platform is described extensively in [3]. - Measure the integrity and security posture of all resources by establishing a continuous diagnostics and mitigation (CDM) or similar system to monitor the state of devices and applications and apply patches or fixes as needed. - An enterprise should collect data about the resource security posture, network traffic, and access requests; process that data; and use any insight gained to improve policy creation and enforcement. This data can also be used to provide context for access requests from subjects.

The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in Federal information systems. The usability considerations are further divided into memory, physical, and environmental considerations. Several themes emerged when looking across authentication methods: - Any authentication method requiring text entry, such as knowledge-based authentication (KBA) and passwords, will have critical usability issues. - Personal Identification Numbers (PINs) may be slightly better than complex passwords since they require fewer keystrokes. However, even PINs will not work for gloved first responders. - Any authentication method requiring that users recall information, such as KBA or memorized secret tokens (e.g., passwords, PINs, gestures) will have significant memory usability considerations. Memory issues may be exacerbated in stressful situations. - For authentication methods that require a separate physical device (e.g., smartcard, wearable proximity token), first responders must remember to bring the device and have it readily accessible for authentication. If the device is used in conjunction with another authentication method (e.g., smartcard with PIN) the usability issues are magnified. - Biometric authentication may be difficult for first responders in certain situations. Fingerprints will only work for users who are not wearing gloves.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Health and Human Services Office of the Secretary 45 CFR Parts 160 and 164 RIN 0945-AA22 AGENCY: Office for Civil Rights (OCR), Office of the Secretary, Department of Health and Human Services. ACTION: Notice of proposed rulemaking; notice of Tribal consultation. SUMMARY: The Department of Health and Human Services (HHS or Department) is

issuing this notice of proposed rulemaking (NPRM) to solicit comment on its proposal to modify the Security Standards for the Protection of Electronic Protected Health Information (Security Rule) under the Health Insurance Portability and Accountability Act of 1996 (HIPAA) and the Health Information Technology for Economic and Clinical Health Act of 2009 (HITECH Act). The proposed modifications would revise existing standards to better protect the confidentiality, integrity, and availability of electronic protected health information (ePHI). The proposals in this NPRM would increase the cybersecurity for ePHI by revising the Security Rule to address: changes in the environment in which health care is provided; significant increases in breaches and cyberattacks; common deficiencies the Office for Civil Rights has observed in investigations into Security Rule compliance by covered entities and their business associates (collectively, regulated entities); other cybersecurity guidelines, best practices, methodologies, procedures, and processes; and court decisions that affect enforcement of the Security Rule.

DATES: Comments: Submit comments on or before March 7, 2025. Meeting: Pursuant to Executive Order 13175, Consultation and Coordination with Indian Tribal Governments, the Department of Health and Human Services' Tribal Consultation Policy, and the Department's Plan for Implementing Executive Order 13175, the Office for Civil Rights solicits input from Tribal officials as the Department develops the modifications to the HIPAA Security Rule at 45 CFR part 160 and subparts A and C of 45 CFR part 164. The Tribal consultation meeting will be held on February 6, 2025, at 2 p.m. to 3:30 p.m. eastern time.

ADDRESSES: You may submit comments, identified by RIN Number 0945-AA22, by any of the following methods. Please do not submit duplicate comments. Federal eRulemaking Portal: You may submit electronic comments at <https://www.regulations.gov> by searching for the Docket ID number HHS-OCR-0945-AA22. Follow the instructions at <https://www.regulations.gov>

non-cloud FIS) to: (1) Develop and maintain a list of the physical location of all operational technology (OT) equipment included within the boundary of the non-cloud FIS; (2) When requested by the Government, submit a copy of the OT equipment list to the Government; (3) Submit a copy of their continuous monitoring strategy for the FIS; and (4) For FISs categorized as FIPS Publication 199 moderate or high security impact, submit the results of: an annual independent assessment of the security of the FIS, and an annual cyber threat hunting and vulnerability assessment.

A. Regulatory Familiarization and Standards Document Reviews It is estimated that approximately all six small business entities, and up to seven small business subcontractor entities, awarded a contract to design, implement, operate, or maintain a FIS on behalf of the Government will need to become familiar with the various compliance requirements of the new clauses 52.239-YY or 52.239-XX, as well as review any applicable standards documents, to be prepared to develop, implement, operate, or maintain a cloud and/or non-cloud FIS, as applicable.

B. Develop and Submit OT Equipment List It is estimated that approximately three small business entities, and up to seven small business subcontractor entities, will be awarded a contract or subcontract annually to develop, implement, operate, or maintain a non-cloud FIS. Each of these entities, will be required to develop, maintain, and submit a list of OT equipment for the duration of the contract. The list must include: (1) the identification and location of any controllers, relays, sensors, pumps, actuators, Open Platform Communications Unified Architecture devices, and other industrial control system devices, as well as all the IP (printed page 68412) addresses assigned to the different hardware components, used in performance of the contract; (2) An explanation of whether the device is password protected and, if so, whether it can be changed, (3) an explanation of whether the device is accessible remotely; and (4) whether multi-factor authentication is present and enabled. The location information in the list must include enough detail to affirmatively locate the OT equipment, when necessary, and track any movement of such equipment during performance of the contract. It is estimated that one of these three small business entities, and up to seven small business subcontractor entities, will be asked to submit the OT equipment list to the Government each year. To develop and maintain the list of OT equipment, a small business will need at least one employee within an information system occupation series (e.g., computer system analyst, information security analyst, system administrator, network architect) to identify the requisite devices used in performance of the contract, track the location of such devices as changes occur, and update and modify the OT equipment list as necessary.

C. Submit Continuous Monitoring Strategy

(viii) Proprietary information submitted strictly on a voluntary basis, absent any exercised authority prescribing criteria for submission. Examples of exercised authorities prescribing criteria for submission are statutes, Executive Orders, regulations, invitations for bids, requests for proposals, and contracts. Submission of information under these authorities is not voluntary.

(2) When the Components receive FOIA requests for information that could be protected by this

Exemption, submitter notice shall be provided. See § 286.2. (e) Exemption 5. Pursuant to 5 U.S.C. 552(b)(5), inter-agency or intra-agency memorandums or letters containing information considered privileged in litigation are exempt from disclosure. The courts have construed 'privileged in litigation' to mean information that is normally privileged in the civil discovery context (U.S. Department of Justice (DOJ) Guide). [3] Merely being an internal record is an insufficient basis for withholding under this exemption. Records that are not available routinely through the discovery process in the course of litigation with the agency because they are privileged should not be withheld under this exemption. The most common discovery privileges have been incorporated into Exemption 5. These privileges are the deliberative process, the attorney work product, and the attorney client privilege. (1) Threshold. (i) A document must meet the threshold requirement of being an inter- or intra-agency document before the proper privilege can be identified in any given case. Because in many instances the Government must seek expert advice from external entities (or consultants), the courts developed an 'outside consultant' test which helps in determining whether such an external entity qualifies as an 'agency' for the purposes of this exemption. If an entity meets the test, then documents it originates may be protected by Exemption 5. (ii) The Components should be careful to ensure that the outside consultant is not an interested party in the agency decision-making process. In 2001, the U.S. Supreme Court ruled that the threshold of Exemption 5 does not encompass communications between an outside consultant (in this case, several Indian tribes) and the Government (the U.S. Department of the Interior (DOI)). In this case, the outside consultants offered an expert opinion on an issue under consideration by DOI. The Supreme Court found that the tribes had an interest in the outcome of the DOI final decision; therefore, the DOI communications did not meet the threshold of Exemption 5. (DOJ FOIA Post Web site) (2) The privileges and types of information protected by Exemption 5 include: (i) Deliberative process privilege.

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Office of the Secretary 32 CFR Part 236 [DOD-2009-OS-0183] RIN 0790-AI60 AGENCY: Office of the DoD Chief Information Officer, DoD. ACTION: Final rule. SUMMARY: This final rule responds to public comments regarding the establishment of the DIB CS/IA program, a voluntary cyber security information sharing program between DoD and eligible DIB companies. The program enhances and supplements DIB participants' capabilities to safeguard DoD information that resides on, or transits, DIB unclassified information systems. DATES: Effective Date: This rule is effective November 21, 2013. FOR FURTHER INFORMATION CONTACT: Mr. Dan Prieto at 703-571-5911, or the DIB Cyber Security and Information Assurance Program Office: (703) 604-3167, toll free (855) 363-4227, email osd.ncr.dod-cio.mbx.dib-cs-ia-program-registration@mail.mil . SUPPLEMENTARY INFORMATION: Executive Summary This final rule responds to public comments regarding the establishment of the DIB CS/IA program, a voluntary (printed page 62431) cyber security information sharing activity between DoD and eligible DIB companies to enhance and supplement DIB participants' capabilities to safeguard DoD information that resides on, or transits, DIB unclassified information systems. The program is codified at 32 CFR Part 236 and implements DoD statutory authorities to establish programs and activities to protect DoD information and DoD information systems, including information and information systems operated and maintained by contractors or others in support of DoD activities (see 10 U.S.C. 2224 and the Federal Information Security Management Act (FISMA), codified at 44 U.S.C. 3541

(Response) FDA notes that we computed the retention costs of the proposed rule on a per-facility basis and that we assumed that costs did not differ significantly from those of current business practices. The example documented in the comment illustrates the small amount of storage space that is required per facility. In the PRIA, FDA assumed that all firms keep most of the proposed records so that larger firms with a larger quantity of records may find it necessary to retain off-site records storage. In the final rule, FDA has revised the recordkeeping retention and other requirements for transporters to be consistent with current requirements for interstate transportation. Consequently, the retention requirements from this final rule should impose no extra burden on these facilities. (Comment 191) One comment from an association of wholesalers states that its members typically retain invoices and shipping records for approximately 6 months and will find it difficult to find the storage space to retain records under the proposed requirements. The

comment states that a 2-year retention requirement would constitute a dramatic change in distributors' operations and lead to a substantial increase in data storage costs. (Response) FDA does not agree that the retention requirements from this final rule will impose a large burden on food businesses. Only a small fraction of information is required to be added to existing records. Furthermore, based on preliminary research, a survey of dietary supplement manufacturers, and our interpretation of most of the comments to the proposed rule, the retention requirements in this final rule do not differ substantially from the industry norm. We believe that any change in practice from wholesalers that generates costs is mostly included in the estimated redesign and other set-up costs. 4. Records Access Costs (Comment 192) One comment states that a 4 and 8 hour records access cost is an additional cost, because it requires retrieval on the weekends, which may require companies to renegotiate storage contracts to allow for weekend access. (Response) FDA researched typical records storage contracts and found that at least one company's standard records retention contract explicitly provides that "unscheduled or emergency delivery of records" was to be charged on a "per event" basis (Ref. 26). FDA assumes this to be the norm in the industry. For both the proposed and final rules, FDA does not estimate the probability of a records access request, and weekend access is assumed to be charged on a per-event basis, which is considered a cost of performing a records access request. Because the records access costs are estimated to be the private costs of planning for a records access request, rather than for performing a records access request, the estimates for planning for a records access request in the analysis of the final rule do not change.

As shown in Table III-10 and Table III-II and Figures III-6 through III-38, the vast majority of the controls are reported either in place or in place and planned. The notable exception is certification/accreditation, which is reported less than 60 percent in place or in place and planned. Also, integrity and confidentiality controls for General ADP Support System (GADPS) are reported only approximately 80% in place or planned. OMB Bulletin 88-16 defined these controls narrowly as encryption, message authentication, and other technical mechanisms. On the other hand, integrity controls for Major Application Systems (MAS), which were 94% in place and planned, include a broad array of data validation mechanisms, such as edit checks and processing integrity checks.

Clearance Agency U.S. Nuclear Regulatory Commission, ATTN: Director of Facilities and Security Personnel Security, 11545 Rockville Pike, Rockville, MD 20853 (301) 415-8080 Central Verification Agency U.S. Nuclear Regulatory Commission, ATTN: Director of Security Facilities Security, 11545 Rockville Pike, Rockville, MD 20853 (301) 415-8080 (printed page 83364) (d) DHS. Table 6 to Paragraph (d) DHS Cognizant Security Office Designation Mailing address Telephone No. CSO DHS Cognizant Security Office, ATTN: Chief Security Officer, 245 Murray Lane, M/S 0120-3, Washington, DC 20528 (202) 447-5424; (202) 447-5345 Dated: December 11, 2020. Patricia L. Toppings, OSD Federal Register Liaison Officer, Department of Defense. Footnotes 1. On June 20, 2020, the Secretary of Defense re-named the Defense Security Service (DSS) as the Defense Counterintelligence and Security Agency (DCSA), as required by Executive Order 13467, section 2.6(b)(i) (as amended by Executive Order 13968, Apr. 24, 2019, 84 FR 18125). Pursuant to Section 4 of E.O. 13968, references to DSS in DoD issuances should be deemed or construed to refer to DCSA. Back to Citation [FR Doc. 2020-27698 Filed 12-18-20; 8:45 am] BILLING CODE 5001-06-P

However, another comment states that FDA's intent to assert jurisdiction over food, whether or not it enters interstate commerce, may be unconstitutional. The comment notes that this assertion of power to regulate food in intrastate commerce is inconsistent with limitations imposed by the Commerce Clause of the U.S. Constitution, which generally authorizes Congress to regulate purely interstate commerce only. The comment further states that FDA should have assumed that Congress did not intend to violate the Constitution, and should revise the proposed rule accordingly. Another comment states that the FDA is proposing that domestic persons must maintain appropriate records as stipulated by the proposed regulations regardless of whether their food enters interstate commerce. The comment adds that appropriate State, local, and municipal regulatory bodies have authority to regulate domestic persons who manufacture, process, pack, transport, distribute, receive, or hold food intended for human or animal consumption, when intended solely for intrastate commerce in the United States. The comment argues that the proposed regulations regarding recordkeeping should not be expanded beyond what has been set forth in the Bioterrorism Act. Another comment states that the FMCSA has guidelines for determining whether carriers and drivers are engaged in interstate commerce

and provides the following definition in 49 CFR part 390.5 : Interstate commerce means trade, traffic, or transportation in the United States: (1) Between a place in a State and a place outside of such State (including a place outside of the United States); (2) Between two places in a State through another State or a place outside of the United States; or (3) Between two places in a State as part of trade, traffic, or transportation originating or terminating outside the State or the United States. (Response) In the preamble to the proposed rule, FDA sought comments on its tentative conclusion that it has authority to require recordkeeping by persons engaged only in intrastate commerce. FDA also sought comments on how many intrastate persons would not be covered by one of the exclusions (printed page 71572) from the recordkeeping requirements (e.g., the farm or restaurant exemption). Based on consideration of the received comments and further review of the provision of the Bioterrorism Act that provides FDA with the authority to require the establishment and maintenance of records by all persons who engage in specified activities involving food, FDA has concluded that the Bioterrorism Act gives FDA authority to require persons to establish and maintain records, whether or not they engage in interstate commerce, as long as they fall within Congress's power to legislate in this area. FDA is mindful that its interpretation of the Bioterrorism Act should not cast doubt on the constitutionality of the statute. (See *Solid Waste Agency of Northern Cook County v. U.S.*

FAR 32.1004(b)(2)(i) states that performance-based payments shall reflect prudent contract financing provided only to the extent needed for contract performance, and FAR 32.1004(b)(3)(ii) states that the contracting officer shall ensure that performance-based payment amounts are commensurate with the value of the performance event or performance criterion and are not expected to result in an unreasonably low or negative level of contractor investment in the contract. DoD is not trying to limit reasonable cash flow with this rule as it does not differ from FAR 32.1004 (b)(2)(ii) which limits contract financing to 90% of price. Any training provided will be done so in accordance with the rules in the FAR and DFARS. 10. Applicability to Acquisition of Commercial Items Comment: One respondent recommended that DoD should consider making PBPs available to commercial item contracts that are large in terms of scope and dollar value when the contractor needs early funding of the facilities, equipment, supplies and the like for performance. The respondent requested that DoD should provide guidance for such use of PBPs. Response: The law contemplates the use of financing similar to performance based payments on commercial item as well as other contracts. However, it also requires that payments for commercial items be made under such terms and conditions as the head of the agency determines are appropriate or customary in the commercial marketplace and are in the best interests of the United States. (10 U.S.C. 2307(f)(1)). It is impossible to specify in the DFARS what specific terms and conditions for PBPs are appropriate or customary in the commercial marketplace, since we assume they may vary widely depending on the marketplace for the kind of supply or service item being purchased. For this reason, the FAR and DFARS do not provide further detailed guidance other than what is already prescribed in FAR 32.2 and DFARS 232.2, Commercial Item Purchase Financing. III. Applicability to Contracts at or Below the Simplified Acquisition Threshold and for Commercial Items, Including Commercially Available Off-the-Shelf Items This rule amends the clauses at DFARS 252.232-7012 and 252.232-7013 and adds a new provision at DFARS 252.232-7015, Performance-Based Payments-Representation. These clauses and provision do not apply to contracts at or below the simplified acquisition threshold or for the acquisition of commercial items. In accordance with 10 U.S.C. 2307(f) and 41 U.S.C. 4505

One commenter interpreted CMMC Level 3 assessment requirements as meaning all parts of an OSCs infrastructure are within scope for CMMC assessment if the OSC uses a CSP, and recommended the rule specify that security requirements from the CRM must be documented in the SSP. Another asked whether OSCs must track all FedRAMP controls in their SSP or only those relevant to NIST SP 800-171 R2. Response: Requirements associated with the use of cloud service providers (CSPs) are covered under section (b)(2)(ii)(D) of DFARS clause 252.204-7012. When a CSP is used, it must meet the requirements of the FedRAMP moderate baseline or the equivalent. The rule was updated for consistency with those requirements, and now requires FedRAMP moderate or FedRAMP moderate equivalency as defined in DoD Policy. §§ 170.16(c)(2), 170.17(c)(5), 170.18(c)(5) address CMMC requirements for CSPs. The CMMC rule does not add new requirements on the use of CSPs, which are found in DFARS clause 252.204-7012. A CSP must be assessed against the FedRAMP moderate baseline when the CSP processes, stores, or transmits CUI. The CMMC rule does not oppose or contradict the requirements of DFARS clause 252.204-7012, nor does this rule relieve a CSP from any requirement defined in DFARS clause 252.204-7012. § 170.17(c)(5)(iii) and the corresponding requirement in § 170.18(c)(5)(iii) only apply to CSPs used to process, store, or transmit CUI in the execution of

the contract or subcontract requiring CMMC assessment. It does not expand to any cloud provider outside the scope of the assessment. Interactions between DoD contractors and their service providers are beyond the scope of the rule. CMMC Level 2 self-assessment and affirmation requirements described in § 170.16 make clear that an OSA using a FedRAMP Authorized CSP (at the FedRAMP Moderate or higher baseline) is not responsible for the CSP's compliance. The OSA needs to document in its SSP how the OSA meets its requirements assigned in the CSP's CRM. When using a CSP that is not FedRAMP Authorized, the OSA is responsible for determining if the CSP meets the requirements for FedRAMP Moderate equivalency as specified in DoD policy. In this case, the OSA also needs to document in its SSP how the OSA meets the requirements assigned to it in the CSP's CRM. The rule has been updated to include verbiage from the DFARS clause 252.204-7012 in the performance of a contract: for consistency. Use of the term CUI in this rule is deliberate because DoD intends to assess compliance with NIST SP 800-171 R2 for all CUI. The DoD declines to replace the word CUI with the word CDI, as the term CUI more clearly conveys that NIST SP 800-171 is the requirement for all CUI information, as described in 32 CFR 2002.14 .

<!-- image --> ## Privacy Annual Report 2021 ## Cybersecurity and <!-- image --> <!-- image -->
<!-- image --> NIST SPECIAL PUBLICATION 800-220 ## Fiscal Year 2021 Cybersecurity & Privacy
Annual Report PATRICK O'REILLY, EDITOR Computer Security Division Information Technology
Laboratory KRISTINA RIGOPOULOS, EDITOR Applied Cybersecurity Division Information Technology
Laboratory CO-EDITORS: Larry Feldman Greg Witte Huntington Ingalls Industries Annapolis Junction,
Maryland THIS PUBLICATION IS AVAILABLE FREE OF CHARGE FROM <https://doi.org/10.6028/NIST.SP.800-220>
SEPTEMBER 2022 <!-- image --> U.S. DEPARTMENT OF COMMERCE Gina M. Raimondo, Secretary NATIONAL
INSTITUTE OF STANDARDS AND TECHNOLOGY Laurie Locascio, NIST Director and Under Secretary of
Commerce for Standards and Technology ## Table of Contents | Foreword.....
.....
..... | 1 | |-----

-|----| | Focus Area 1: Cryptographic Standards and
Validation..... | 2 | | Focus Area 2:
Cybersecurity
Measurement.....
| 6 | | Focus Area 3: Education and Workforce.....
..... | 9 | | Focus Area 4: Identity and Access
Management..... | 12 | |
Focus Area 5: Privacy Engineering.....
.....

(C) Require CMMC Ecosystem members to have and maintain a satisfactory record of integrity and business ethics. § 170.9 CMMC Third-Party Assessment Organizations (C3PAOs). (a) Roles and responsibilities. C3PAOs are organizations that are responsible for granting CMMC Level 2 Certification Assessments and issuing certificates of assessment for OSCs. C3PAOs must be accredited or authorized by the Accreditation Body in accordance with the requirements set forth. (b) Requirements. C3PAOs shall: (1) Obtain authorization or accreditation from the Accreditation Body in accordance with § 170.8(b)(3). (2) Comply with the Accreditation Body policies for Conflict of Interest, Code of Professional Conduct, and Ethics set forth in § 170.8(b)(17); and achieve and maintain compliance with ISO/IEC 17020:2012 (incorporated by reference, see § 170.2) within 27 months of authorization. If ISO/IEC 17020:2012 is revised or superseded, the C3PAO shall achieve full compliance with the updated standard within 12 months of the date of revision. (3) Require all C3PAO company personnel participating in the CMMC assessment process to complete a Tier 3 background investigation resulting in a determination of national security eligibility. This includes the CMMC Assessment Team and the quality assurance individual. This Tier 3 background investigation will not result in a security clearance, and is not being executed for the purpose of government employment. The Tier 3 background investigation is initiated using the Standard Form (SF) 86. These positions are designated as non-critical sensitive with a risk designation of 'Moderate Risk' in accordance with title 5 CFR 1400.201(b) and (d) and the investigative requirements of title 5 CFR 731.106(c)(2). (4) Require all C3PAO company personnel participating in the CMMC assessment process who are not eligible to obtain a Tier 3 background investigation to meet the equivalent of a favorably adjudicated Tier 3 background investigation. DoD will determine the Tier 3 background investigation equivalence for use with the CMMC Program only. (5) Comply with Foreign Ownership, Control or Influence (FOCI) by: (i) Completing and submitting Standard Form (SF) 328 Certificate

Pertaining to Foreign Interests upon request from DCSA and undergo a National Security Review with regards to the protection of controlled unclassified information based on the factors identified in 32 CFR 117.11(b) using the procedures outlined in 32 CFR 117.11(c) . (ii) Receiving a non-disqualifying eligibility determination from the CMMC PMO resulting from the FOCI risk assessment in order to proceed to a DCMA DIBCAC CMMC Level 2 assessment as part of the authorization and accreditation process set forth in paragraph (b)(6) of this section.

To select a CMMC Level for a procurement, Program Managers and requiring activities will identify the applicable CMMC Level using the factors included in § 170.5(b)(1) through (5). The DoD did agree with one comment to rephrase § 170.5(b)(4) to delete a reference to the potential for impact from exploitation of information security deficiencies, which likely cannot be effectively determined. The DoD does not agree that the wording equates to a sub-CONFIDENTIAL classification and declines to delete that criterion. § 170.5(b)(3) is appropriately worded in that it states Program Managers will consider the listed criteria in selecting a CMMC requirement level. It does not have the effect of transforming FCI into CUI. The DoD reserves the right to define the criteria for selection of the CMMC assessment requirement, just as it defines all other requirements for inclusion in a solicitation. The Department remains committed to implementing the CMMC program to require compliance assessment against applicable security requirements in all DoD contracts involving FCI or CUI. Some such contracts will require only a CMMC self-assessment, while others will require a certification assessment. The commenter misinterprets that some contracts that do require processing of FCI or CUI will not require CMMC assessment of either kind, without approval of a waiver. The DoD declines to remove self-assessments from the rule. Self-assessments allow the acquiring organization to balance the cost and complexity of assessment with the risk to the information being shared with the OSA. Supporting guidance for CMMC implementation will be updated, as necessary. DoD has options to mitigate implementation issues such as waivers and other contractual remedies. DoD's estimate for the number of contractor's requiring CMMC Level 1 and cost estimates represent derived estimates based on internal expertise and public feedback in accordance with OMB Circular A-4. 12. Flow-Down/Applicability to Sub Contractors a. Applicability and Compliance Comment: Several comments requested clarification about the applicability of CMMC requirements to subcontractors and how to correctly flow down requirements. Some asked whether prime contractors would have flexibility to flow down a lower CMMC level than required for the prime contract. Three comments expressed confusion about the type of Level 2 assessment required for subcontractors when supporting a prime that is required to meet CMMC Level 3 requirements. Two asked about the impact to flow-down when contractors hold multiple contracts. A couple comments requested clarity on how to determine the correct CMMC level to flow down. Some comments asked what factors would result in flow-down of a particular CMMC requirement level, or whether affirmations submitted by primes would require knowledge of subcontractor compliance status.

Control ES-128: st lattice vectors using spherical locality-sensitive hashing. Progress in Cryptology - LATINCRYPT 2015 , eds Lauter K, Rodríguez-Henríquez F (Springer International Publishing, Cham), pp 101-118. - [310] Becker A, Ducas L, Gama N, Laarhoven T (2016) New directions in nearest neighbor searching with applications to lattice sieving. Proceedings of the Twenty-Seventh Annual ACM-SIAM Symposium on Discrete Algorithms SODA '16 (Society for Industrial and Applied Mathematics, USA), p 10-24. - [311] Ducas L (2018) Shortest vector from lattice sieving: A few dimensions for free. Advances in Cryptology - EUROCRYPT 2018 , eds Nielsen JB, Rijmen V (Springer International Publishing, Cham), pp 125-145. - [312] Laarhoven T, Mariano A (2018) Progressive lattice sieving. Post-Quantum Cryptography , eds Lange T, Steinwandt R (Springer International Publishing, Cham), pp 292-311. - [313] Doulgerakis E, Laarhoven T, de Weger B (2020) Sieve, enumerate, slice, and lift. Progress in Cryptology - AFRICACRYPT 2020 , eds Nitaj A, Youssef A (Springer International Publishing, Cham), pp 301-320. - [314] Zhao Z, Ding J (2022) Several improvements on BKZ algorithm, Cryptology ePrint Archive, Report 2022/239. - [315] Kirshanova E, Laarhoven T (2021) Lower bounds on lattice sieving and information set decoding. Advances in Cryptology - CRYPTO 2021 , eds Malkin T, Peikert C (Springer International Publishing, Cham), pp 791-820. - [316] Hanrot G, Pujol X, Stehlé D (2011) Terminating BKZ, Cryptology ePrint Archive, Report 2011/198. - [317] Chen Y, Nguyen PQ (2011) BKZ 2.0: Better lattice security estimates. Advances in Cryptology - ASIACRYPT 2011 , eds Lee DH, Wang X (Springer Berlin Heidelberg, Berlin, Heidelberg), pp 1-20. - [318] Yu Y, Ducas L (2018) Second order statistical behavior of LLL and BKZ. Selected Areas in Cryptography - SAC 2017 , eds Adams C, Camenisch J (Springer International Publishing, Cham), pp 3-22.

The Security Object enforces integrity of the CCC according to the issuer. All FIPS 201 mandatory information printed on the card is duplicated on the chip in that data object. The printed information data object SHALL NOT be modified post-issuance. The Security Object enforces integrity of this information according to the issuer. This provides specific protection that the card information must match the printed information, mitigating alteration risks on the printed media. The Security Object enforces integrity of the Discovery Object according to the issuer.

software) or technical controls. Under the proposal, a regulated entity would be required to collect sufficient information to understand what a specific activity in its relevant electronic information systems is, such that the regulated entity would be better able to address activity that presents a risk to the confidentiality, integrity, or availability of ePHI. For example, a regulated entity should understand that a given activity in a relevant electronic information system is an attempt to access a portable workstation without authorization. The proposal also would modify the limitation on the regulated entity's obligation to record and identify activity in its relevant electronic information systems. Thus, the proposal would require a regulated entity to record and identify any activity that could present a risk to ePHI, meaning activity in all of its relevant electronic information systems, not only in its electronic information systems that create, receive, maintain, or transmit ePHI. In so doing, the Department would also require a regulated entity to record and identify activity in its electronic information systems that may affect the confidentiality, integrity, or availability of ePHI. This redesignated standard, as proposed, aligns more closely with the Department's enhanced CPG for Centralized Log Collection by addressing the deployment of technical controls to record and identify activity in all electronic information systems. [763] Additionally, as an example, we note that adoption of health IT certified through the ONC Health IT Certification Program may contribute to a regulated entity's compliance with the proposed standard for audit trail and system log controls where such health IT meets the criteria for auditing actions on health information and recording actions related to electronic health information and audit log status. [764] (printed page 973) The Department proposes four implementation specifications under this proposed standard that are intended to improve the effectiveness of audit controls deployed by a regulated entity. The proposed implementation specification for monitoring and identifying activity at proposed 45 CFR 164.312(d)(2)(i) would require a regulated entity to deploy technology assets and/or technical controls that monitor in real-time (i.e., contemporaneously) all activity occurring in a regulated entity's relevant electronic information systems and identify indications of unauthorized persons and unauthorized activity, as determined by the regulated entity's risk analysis. As proposed, the technology assets and/or technical controls also would be required to alert workforce members of such indications in accordance with the regulated entity's policies and procedures for information system activity review at proposed 45 CFR 164.308(a)(7)

There is the possibility that direct marketers are included in the estimate of the number of direct marketers cited earlier and excluded in the NES if they are casual market participants, and have temporarily left the industry, or if they do not file as a sole proprietorship business with the IRS. Casual market participants might be included in the estimate of the total number of direct market facilities even if they are not active members. This would tend to inflate the total number of direct marketers to include both active and inactive members. Because of the ease of entry and exit by these firms, casual direct marketers that have temporarily left the industry are assumed to be approximately half of the number of direct marketers of food, or 1.75 percent of all direct marketers. This assumption leaves an estimated 1.75 percent (175,000) of direct marketers that are not counted in the NES statistics because they did not file as a sole proprietorship business with the IRS. We use this estimate of the number of direct food marketers that did not file as a sole proprietorship business with the IRS to revise our estimate of the total number of retail facilities. Direct marketers that did not file as a sole proprietorship business with the IRS are assumed to be part-time suppliers and to sell mostly at the retail level. Furthermore, because these are very small businesses that only sell food products on a part-time basis, the additional records maintenance costs for these facilities will be considerably less than that for larger, full-time businesses. We estimate the additional records maintenance costs for these part-time facilities to be one half that for other retailers. The learning costs, records redesign costs, and records access planning costs for these facilities are assumed to be the same as for other facilities. FDA does not agree that the burden of the rule would be higher for direct marketers than for other retailers. In the PRIA, FDA estimated that about 88 percent of retailers classified as very small firms have fewer than 10 employees. FDA believes it is reasonable to assume that compliance costs for direct

marketers would be about the same as for other very small firms. (Comment 184) One comment suggests that FDA underestimated the number of mixed-type facilities that engage in nut farming. The comment states that, in the almond industry, there are about 360 hullers and processors who are also growers, while FDA estimated that there were only 290 mixed-type facilities that engage in all categories of nut farming. Furthermore, because there are about 6,000 almond growers, the comment states that this implies that 6 percent of all almond growers would be classified as mixed-type facilities, compared to FDA's estimate of 2 percent of all nut farms.

1. Create a part of the cloud to meet the specific and varying security requirements of users. 2. Control access to that portion of the cloud so that the correct applications (workloads) get deployed there. 3. Enable audits of that portion of the cloud so that users can verify compliance.

1. Configure a cloud server platform as being trusted. The 'cloud server platform' includes the hardware configuration (e.g., BIOS integrity), operating system (OS) configuration (boot loader and OS kernel configuration and integrity), and the integrity of the container runtime. This also includes the varying hardware security technologies enabled on the server. These chain of trust (CoT) technologies provide platform integrity verification. Additional technologies and details can be found in the aforementioned NISTIR 8320 [1] and are discussed in Section 3.2. 2. Before each container worker node launch, verify (measure) the trustworthiness of the cloud server platform. The items configured in goal 1 (BIOS, OS, container runtime) need to have their configurations verified against previous measurements before launching the container runtime to ensure that the assumed level of trust is still in place. 3. During container runtime execution, periodically audit the trustworthiness of the cloud server platform. This periodic audit is essentially the same check as that performed as goal 2, except that it is performed frequently while the container runtime is executing. Ideally this checking would be part of continuous monitoring.

1. Deploy workloads only to cloud servers with trusted platforms. This basically means that you perform stage 0, goal 3 (auditing platform trustworthiness) and only deploy a workload to the cloud server if the audit demonstrates that the platform is trustworthy.

enables a regulated entity to determine if any ePHI has been used or disclosed in an inappropriate manner. [525] The procedures should be customized to meet the regulated entity's risk management strategy and consider the capabilities of all information systems with ePHI. [526] These activities should also promote continual awareness of any information system activity that could suggest a security incident. [527] Detecting and preventing data leakage initiated by malicious authorized users is a significant challenge. [528] Identifying potential malicious activity in relevant electronic information systems, including in workstations and other components, as soon as possible is key to preventing or mitigating the impact of such activity. [529] To identify potential suspicious activity, organizations should consider an insider's interactions with information systems and their components. A regulated entity can detect anomalous user behavior or indicators of misuse by either a trusted employee or third-party vendor who has access to critical systems, workstations and other system components, and data. [530] To minimize this risk, an organization may employ safeguards that detect suspicious user activities, such as traffic to an unauthorized website, downloading data to an external device (e.g., thumb drive), or access to a network server by an unauthorized mobile device. Maintaining audit controls (e.g., system event logs, application audit logs) and regularly reviewing audit logs, access reports, and security incident tracking reports are important security measures that can assist in detecting and identifying suspicious activity or unusual patterns of data access. [531] Regulated entities should regularly review activity in their relevant electronic information systems (including the components of such systems) for potential concerns and consider ways to automate such reviews. [532] Additionally, regulated entities are responsible for establishing and implementing appropriate standard operating procedures, including determining the types of audit trail data and monitoring procedures that would be needed to derive exception reports. [533] They also must activate the necessary review processes and maintain auditing and logging activity. [534] Department and NIST guidance advise regulated entities to consider many questions when establishing their policies and procedures for reviewing activity in their relevant electronic information systems review. [535] These include: What logs or reports are generated by the information systems? Is there a policy that establishes what reviews will be conducted? Are there corresponding procedures that describe the specifics of the reviews? Who is responsible for the overall process and results? How often will review results be analyzed? Where will audit information reside (e.g., separate server)? Will it be stored external to the organization (e.g., cloud service provider)?

2. Guidance on the use of an evaluation factor regarding supply chain risk is modified to require the inclusion of the evaluation factor when acquiring information technology, whether as a service or as a supply that is a covered system, is a part of a covered system, or is in support of a covered system. Additional text regarding an evaluation factor has been added at DFARS 212.301, 213.106-1, 214.201-5, and 214.503-1. 3. DFARS clause 252.239-7018, Supply Chain Risk, is changed as follows:

a. Paragraph (b), is modified to state that the contractor shall mitigate supply chain risk in the provision of supplies and services to the Government; and b. Paragraph (c) is removed as the clause will no longer contain a requirement to flow down the clause to subcontractors.

B. Analysis of Public Comments

1. Interim Rule Should Be Reissued as a Proposed Rule Comment: Numerous respondents urged DoD to rescind the interim rule and reissue the rule as a proposed rule. One respondent suggested that the new rule authorizes the exclusion of businesses from the defense industrial base and that such authority should not be exercised without first hearing the views of and gathering all relevant information from the parties that will be directly impacted by this rule. One respondent commented that the rule could prevent suppliers from addressing and mitigating supply chain security risks, and that a public comment period would have allowed industry to suggest alternative approaches that could allow for risk mitigation. Another respondent commented that the interim rule denies industry and other critical stakeholders ample time, opportunity to shape, and ultimately collaborate with the DoD to design a complex program that addresses multiple risks and complexities. One respondent added that without a standard notice-and-comment rulemaking process, industry has no opportunity to comment on areas of concern before the rule takes effect whereby industry must incur costs and move towards compliance without guidance through the rulemaking process. Response: DoD issued an interim rule because of the need to protect national security systems (NSS) and the integrity of its supply chains. The rule implements the specific authorities provided in the statute. The pilot authority provided for by the statute will expire September 30, 2018. It is in DoD's interest to initiate the pilot program and begin gathering feedback for its report to Congress. DoD considered all public comments received during the public comment period in the formation of this final rule.

2. Definitions

a. **·Covered Item·/·Covered System·** Comment: Several respondents objected to the broad definitions of **·covered system·** and **·covered item·**. One respondent questioned why the Council chose to use the term **·covered item·** versus **·covered item of supply·**, which is the term used in section 806. Response:

3.1. Compliance With NIST Standards and Validation 3.1. Compliance With NIST Standards and Validation

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
 Enhanced Security Requirements for Protecting CUI September 2025 ENHANCED SECURITY REQUIREMENT
 ORGANIZATION-DEFINED PARAMETER 03.03.03E [Assignment: organization-defined audit information]
 03.03.04E [Selection (one or more): vulnerability scanning information; performance data; system
 monitoring information; [Assignment: organization-defined data/information collected from other
 sources]] 03.04.02E [Assignment: organization-defined automated mechanisms] 03.04.02E [Selection
 (one or more): disable network access by such components; isolate the components; notify
 [Assignment: organization-defined personnel or roles]] 03.04.03E [Assignment: organization-defined
 automated mechanisms] 03.04.04E [Assignment: organization-defined automated

CMMC program requirements are applicable when DoD requires processing, storing, or transmitting of either FCI or CUI on a non-Federal contractor owned information system in the performance of a contract between DoD and the contractor. The DoD does not manage nor is it involved in data exchanges between contractors and subcontractors.

3. Other DoD Policies and Programs Many comments dealt with DoD policies and programs that, while relevant for understanding CMMC requirements, are still entirely separate programs or policies that are not within the scope of the CMMC program. However, several commenters recommended that the rule be revised to address them. Key topics among such comments include:

a. **Adaptive Acquisition Framework** Comment: One commenter misunderstood CMMC program purpose and thought the requirements applied to systems and capabilities acquired or developed for DoD's use, using formal policies of the Defense Acquisition System. Based on this misinterpretation, this commenter made dozens of recommendations related to integration of CMMC assessment and program requirements with other existing DoD acquisition frameworks and suggested relying on the assessors that complete TRAs, in place of implementing the CMMC program. One of their comments also proposed establishing a single responsible office for CUI and SCRM, hosting CUI material within a single, separate secure and existing cloud-based data warehouse and including

hardware and software approving authorities as part of the proposed rule for GFE. The commentor also stated the role of the Office of Small Business Programs (OSBP) needs to flow down to the Small Business Administration military service offices. The commentor also asked how to reconcile CMMC against the DoDI 8582.01 requirement stating a DoD Component should not specify the content and format of plans of action that address deficiencies or specifying the parameters of security controls. This commentor also recommended creation of a MIL-Standard in lieu of aligning cybersecurity requirements to existing NIST standards, and linkage of CMMC requirements to procedures related to Approval to Operate (which applies to DoD systems. This commentor suggested that the CMMC PMO be made responsible to provide system scans to check for Software Bills of Material as part of DoD's response to Executive Order 14028

External attackers may include foreign adversaries, criminal organizations, and cyber-activists who target an SSC for various reasons, such as espionage or sabotage. Internal attackers pose a significant risk, as they may have insider access to sensitive information - often using legitimate access rights - that allow them to launch attacks or steal confidential information. Additionally, both categories of threat actors may use a variety of techniques to compromise the SDLC environment and steal or manipulate software, such as phishing, malware, social engineering, and physical access. Therefore, companies should be aware of these risks and take appropriate measures (see Sec. 3.2) to secure their SSC. - Malware - Code reuse or the ingest of libraries and dependencies - Social engineering - Network-based attacks - Physical attacks Attack vectors can originate from various sources, including malware attacks on developer workstations, social engineering attacks on developers, network-based attacks on the development environment, and physical attacks on the hardware or networks used by developers. These different attack vectors require distinct countermeasures, including endpoint protection software, network security controls, access control policies, and physical security measures. Companies should identify potential risks and vulnerabilities, assess their security posture, and implement appropriate defensive measures to mitigate threats to their SDLC environment.

- Subverting, removing, or introducing a step within the SSC to maliciously modify or sabotage the resulting software product - Stealing credentials from the build system to mint and sign unauthorized malicious software - Causing naming collisions - Source code - Credentials - Sensitive data - Internal operations - Build systems A software developer's workstation typically contains various assets, including source code, credentials, and access to sensitive information, such as personally identifiable information (PII), protected health information (PHI), intellectual property (IP), cryptographic materials (e.g., software artifact signing keys), and proprietary information. Companies should identify critical assets and implement controls to protect them from unauthorized access, such as access controls, multi-factor authentication, encryption of data at rest and in transit, and data loss prevention (DLP) measures.

(Response) The costs estimated in the PRIA use cost estimates of the juice HACCP rule as a reference, not those of the seafood HACCP regulation. FDA has also received information that costs for compliance with the seafood HACCP rule were underestimated. FDA developed the estimates for the juice HACCP rule much later than those for the seafood HACCP rule. In addition, the burden for the additional records maintenance required in this final rule is considerably less than that required by the juice HACCP rule, particularly because FDA has relaxed the requirement for maintaining lot code information in the final rule and removed the requirement to record and maintain contact information for each transaction. (Comment 200) Some comments state that FDA failed to account for the effect of higher transaction costs (as a result of the regulation) on reducing arbitrage opportunities. Food arbitrage is a line item in most food distributors' and retailers' financial statements. The comments assert that this final rule will result in fewer arbitrage opportunities, because the cost of a transaction will rise, which will cause a substantial reduction in profits, encourage layoffs, and raise consumer prices. (Response) FDA agrees that the recordkeeping provisions in this regulation may increase the costs of transactions, thereby decreasing the total number of transactions. FDA believes, however, that transactions will be only slightly costlier and the effect on consumer prices and arbitrage opportunities will be small. (Comment 201) One comment urges FDA to clarify and confirm that it would not consider records identifying producers of coffee cherry for traceback purposes as information that would be considered to be information reasonably available. The comment states that it would be prohibitively costly to link the identities of individual coffee cherry growers to any processed food item, because the cherries from many growers are typically mixed upon delivery to a processing facility.

Proceedings of the Cybersecurity in CyberPhysical Systems Workshop, April 23 - 24, 2012 ##
Proceedings of the Cybersecurity in CyberPhysical Systems Workshop, April 23 - 24, 2012 The Information Technology Laboratory (ITL) at the National Institute of Standards and Technology (NIST) promotes the U.S. economy and public welfare by providing technical leadership for the Nation's measurement and standards infrastructure. ITL develops tests, test methods, reference data, proof of concept implementations, and technical analyses to advance the development and productive use of information technology. ITL's responsibilities include the development of management, administrative, technical, and physical standards and guidelines for the cost-effective security and privacy of other than national security-related information in Federal information systems.

One respondent while expressing concern that the reporting requirement could be interpreted to require the submission of FAR part 31 compliant costs, stated that costs generated by a GAAP-compliant system should be sufficient to provide DoD with data necessary for negotiation of PBPs in future contracts. This respondent recommended clarification that a contractor may report costs from its GAAP-compliant system, adjusted by a decrement factor to reflect estimated unallowable costs as appropriate. Response: The clauses in the final rule have been revised to specify that if the Contractor's accounting system is not capable of tracking costs on a job order basis, the Contractor shall provide a realistic approximation of the allocation of incurred costs attributable to this contract in accordance with the Contractor's accounting system. DoD considers that it would constitute excessive risk to the Government and would be an impediment to issuing financing payments to a company if that company is unable to comply with this requirement, even when it is properly understood that this clause does not require a Government-unique accounting system. To the extent that a company is unable to report the costs of performance at all, relying on its own accounting books and records, this will make it impossible for the Government to have any confidence that complete performance of the contract is assured, or that the negotiated events reflect prudent contract financing. (FAR 32.1004(b)(2)(i)) and do not result in an unreasonably low or negative level of contractor investment in the contract. (FAR 32.1004(b)(3)(ii)). b. Disincentive to use of PBPs, rather than a preference. Comment: One respondent stated that nontraditional entities may be disinterested in expending time and resources to implement business systems to collect and report costs on a contract basis, which are beyond the system necessary to comply with GAAP. Similarly, another respondent stated that the requirement to report incurred costs undermines the stated preference for PBPs, could deter contractors from pursuing PBPs because contractors with only fixed-price contracts are unlikely to track costs on a contract-by-contract basis, and effectively would require many contractors to add business and compliance systems if they were to pursue PBPs. They suggest that this is therefore contrary to the statutory preference at 10 U.S.C. 2307 for PBPs as a means of financing. Response: If the contractor's financial statements are in compliance with GAAP, it is likely that the contractor, even a nontraditional defense contractor, will have some means of providing a realistic approximation of the allocation of incurred costs. While it is possible that some contractors will have no such system at all, rather than only no Government-unique system, DoD does not believe it is reasonable, necessary, or the intent of Congress, to issue Government financing when the recipient has no such visibility over its costs.

3.2.2 Technology : EPCR application, public safety mobile device, backend server ## Description
While assisting a patient, an EMS employee is recording patient information into an EPCR application.

CMMC Program requirements are designed to require completion of an assessment and an annual affirmation. The purpose of the annual affirmation addressed in § 170.22 is to validate to the DoD that the contractor is actively maintaining its CMMC level status, which is more than a checkbox exercise. One commenter misinterpreted the quoted definition of subcontractor, which makes clear that term includes only those entities providing supplies, materials, equipment, or services under a subcontract in connection with the prime contract. DFARS clause 252.204-7012 and FAR clause 52.204-21 also flow-down the requirement to safeguard information. CMMC program requirements will be flowed down similarly, therefore there is no anticipated expansion of scope. The cost estimates included in the published rule include costs for both existing DIB members and new entrants (or newly covered entities). The DoD modified the Overview summary of CMMC 2.0 to read The DFARS clause 252.204-7012 also requires defense contractors to include this clause in all subcontracts that will require the subcontractor to process, store, or transmit CUI. The DoD declined additional edits in this location that requested reframing the criteria Program Managers will use select CMMC

requirements to address Levels 2 and 3 only. The DoD may apply CMMC Level 2 or 3 requirements when there is anticipation of the need for the contractor or subcontractors to process, store, or transmit CUI during the performance of a contract. b. Prime and Subcontractor Relationships Comment: Many requested specific examples of when a prime contractor should flow down its CMMC requirements to a subcontractor or ESP, and how to determine the appropriate CMMC level to flow down. For example, (printed page 83118) one comment asked whether the subcontract document would require safeguarding, necessitating flow-down of the CMMC requirement. Some comments expressed concern that flow-down requirements are not sufficiently clear to prevent prime contractors from unnecessarily sharing CUI and applying CMMC requirements to lower tier suppliers. Another thought that the flow-down requirements will drastically expand the scope of the program and drive cost increases for the DIB. Several comments suggested strategies for minimizing the burden of security implementation on lower tier subcontractors, such as requiring prime contractors to provide access to CUI on prime contractor systems, or prohibiting prime contractors from unnecessarily sharing CUI information that would necessitate a CMMC requirement. One asked whether the prime contractor has a responsibility to check which CMMC level the subcontractor has flowed down to the next tier. One comment referenced industry activities aimed at gauging subcontractor preparedness for CMMC and expressed concern with anecdotal evidence that primes will not issue orders until the subcontractor has submitted CMMC scores into SPRS. Response:

3.3.2 Job Experience ## Focus Groups In the focus group demographic survey, we asked participants how many years they had worked as government employees, in their current organization, and in a cybersecurity role.

The CSA will meet at least annually, and otherwise as required by circumstances, with the GSCs of contractors operating under a VT, PA, SSA, or SCA to review the purpose and effectiveness of the clearance arrangement and to establish a common understanding of the operating requirements and their implementation. These reviews will include an examination of: (i) Acts of compliance or noncompliance with the approved security arrangement, standard rules, and applicable laws and regulations. (ii) Problems or impediments associated with the practical application or utility of the security arrangement. (iii) Whether security controls, practices, or procedures warrant adjustment. (2) Annual certification. For contractors operating under a VT, PA, SSA, or SCA, the chairman of the GSC will submit to the CSA one year from the effective date of the agreement and annually thereafter, an implementation and compliance report. Such reports will include: (i) A detailed description of the manner in which the contractor is carrying out its obligations under the agreement. (ii) Changes to security procedures, implemented or proposed, and the reasons for those changes. (iii) A detailed description of any acts of noncompliance, whether inadvertent or intentional, with a discussion of remedial measures, including steps taken to prevent such acts from recurring. (iv) Any changes, or impending changes, of KMP or key board members, including the reasons therefore. (v) Any changes or impending changes in the organizational structure or ownership, including any reorganizations, acquisitions, mergers, or divestitures. (vi) Any other issues that could have a bearing on the effectiveness of the applicable agreement. (j) Transactions involving foreign persons, and the Committee on Foreign Investment in the United States (CFIUS). (1) The CFIUS is a USG interagency committee chaired by the Treasury Department that conducts assessments, reviews and investigations of transactions that could result in foreign control of a U.S. business, and certain non-controlling investments and certain real estate transactions involving foreign persons under 50 U.S.C. 4565 . (2) In CFIUS cases where the acquired U.S. business requires access to classified information, the CFIUS assessment, review or investigation, as applicable, and the CSA industrial (printed page 83335) security FOCI review are carried out in parallel, but are separate processes with different time constraints and considerations.

(vi) If the proposed transaction involves access to proscribed information and the contractor is contemplating the use of an SSA to mitigate FOCI, the GCA will provide DSS with a preliminary determination regarding the acceptability of the proposed FOCI mitigation. The determination must be provided to DSS one day prior to the suspense date established by the MIBP CFIUS Team and must include whether a favorable NID will be provided. If the GCA does not notify DSS, DSS will not delay implementation of a FOCI action plan pending completion of a GCA's NID process as long as there is no indication that the NID will be denied. (vii) If DSS, under its FOCI authorities, is notified of a transaction with respect to which the parties thereto have not filed a notice with CFIUS, DSS will notify the MIBP CFIUS Team through the OUSD(I) Security Directorate. (viii) When a merger, sale, or

acquisition of a contractor is finalized prior to having an acceptable FOCI mitigation agreement in place, DSS will take actions consistent with paragraph (b)(2)(iv) of this section. Dated: April 2, 2014. Aaron Siegel, Alternate OSD Federal Register Liaison Officer, Department of Defense. [FR Doc. 2014-07826 Filed 4-8-14; 8:45 am] BILLING CODE 5001-06-P

DFARS 252.204-7021 (Cybersecurity Maturity Model Certification Requirements) Requires CMMC certification at the level specified in the contract, effective Phase 1 November 10, 2025. DFARS 252.204-7021 works in conjunction with the CMMC program. While 252.204-7021 establishes the contractual requirement, CMMC (under 32 CFR Part 170) provides the assessment framework. Phase 1 began November 10, 2025, with Phase 2 (C3PAO certification requirements) scheduled for November 10, 2026.

Control HA-3: zerland, Cham), pp 267-287. - [34] Deshpande S, Xu C, Nawan M, Nawaz K, Szefer J (2023) Fast and efficient hardware implementation of HQC. Selected Areas in Cryptography -SAC 2023 -30th International Conference, Fredericton, Canada, August 14-18, 2023, Revised Selected Papers , eds Carlet C, Mandal K, Rijmen V (Springer), Lecture Notes in Computer Science , Vol. 14201, pp 297-321. - [35] Li C, Song S, Tian J, Wang Z, Koç ÇK (2023) An efficient hardware design for fast implementation of HQC. 36th IEEE International System-on-Chip Conference, SOCC 2023, Santa Clara, CA, USA, September 5-8, 2023 , eds Becker J, Marshall A, Harbaum T, Ganguly A, Siddiqui F, McLaughlin K (IEEE), pp 1-6. 9/SOCC58585.] 2023.10257054 - [36] Antognazza F, Barengi A, Pelosi G, Susella R (2024) A high efficiency hardware design for the post-quantum KEM HQC. IEEE International Symposium on Hardware Oriented Security and Trust, HOST 2024, Tysons Corner, VA, USA, May 6-9, 2024 (IEEE), pp 431-441. 9/HOST55342.2024.10545409 - [37] Misoczki R, Tillich JP, Sendrier N, Barreto PSLM (2013) MDPC-McEliece: New McEliece variants from moderate density parity-check codes. 2013 IEEE International Symposium on Information Theory , pp 2069-2073. 9/ISIT.2013.6620590 - [38] Drucker N, Gueron S, Kostic D (2020) QC-MDPC decoders with several shades of gray. Post-Quantum Cryptography , eds Ding J, Tillich JP (Springer International Publishing, Cham), pp 35-50. - [39] Drucker N, Gueron S, Kostic D (2020) On constant-time QC-MDPC decoders with negligible failure rate. Code-Based Cryptography , eds Baldi M, Persichetti E, Santini P (Springer International Publishing, Cham), pp 50-79.

(iii) Append the servicing Judge Advocate's legal review, including a determination that the Privacy Act Review Board packet is complete. (d) DA Privacy Act Review Board. (1) The DA Privacy Act Review Board acts on behalf of the Secretary of the Army in deciding appeals of the appropriate Denial Authority's refusal to amend records. (2) The Board will process an appeal within 30 working days of its receipt. The General Counsel may authorize an additional 30 days when unusual circumstances and good cause so warrant. (3) The Board membership consists of the following principal members, comprised of three voting and two non-voting members, or their delegates. (4) Three voting members include- (i) Administrative Assistant to the Secretary of the Army (AASA) who acts as the Chairman of the Board; (ii) The Judge Advocate General; and (iii) The Chief, DA Freedom of Information and Privacy Division, U.S. Army Records Management and Declassification Agency. (5) In addition, two non-voting members include- (printed page 24504) (i) The Chief Attorney, OAASA (or designee) who serves as the legal advisor and will be present at all Board sessions to provide legal advice as required; and (ii) Recording Secretary provided by the Office of the Administrative Assistant to the Secretary of the Army. (e) DA Privacy Act Review Board meetings. (1) The meeting of the Board requires the presence of all five members or their designated representatives. Other non-voting members with subject matter expertise may participate in a meeting of the Board, at the discretion of the Chairman. (2) Majority vote of the voting members is required to make a final determination on a request before the Board. (3) Board members, who have denial authority, may not vote on a matter upon which they took Denial Authority action. However, an individual who took Denial Authority action, or his or her representative, may serve as a non-voting member when the Board considers matters in the Denial Authority's area of functional specialization. (4) The Board may seek additional information, including the requester's official personnel file, if relevant and necessary to decide the appeal. (5) If the Board determines that an amendment is warranted (the record is inaccurate as a matter of fact rather than judgment, irrelevant, untimely, or incomplete) it will amend the record and notify the requester, the Denial Authority, the custodian of the record, and any prior recipients of the record, of the amendment. (6) If the Board determines that amendment is unwarranted, they will- (i) Obtain the General Counsel's concurrence in writing; (ii) Respond to the requester with the reasons for denial; and

and subject to the agency's public release procedures. Contractors will request approval for public disclosure of declassified information in accordance with the procedures of this paragraph. (i) Disposition. Contractors will: (1) Establish procedures for review of their classified holdings on a recurring basis to ensure the classified holdings are in support of a current contract or authorization to retain beyond the end of the contract period. (2) Destroy duplicate copies as soon as practical. (3) For disposition of classified material not received under a specific contract: (i) Return or destroy classified material received with a bid, proposal, or quote if the bid, proposal, or quote is not: (A) Submitted or is withdrawn within 180 days after the opening date of bids, proposals, or quotes. (B) Accepted within 180 days after notification that a bid, proposal, or quote has not been accepted. (ii) If the classified material was not received under a specific contract, such as material obtained at classified meetings or from a secondary distribution center, return or destroy the classified material within one year after receipt. (j) Retention. The provisions of § 117.13(d)(5) apply for retention of classified material upon completion of a classified contract. (1) If contractors propose to retain copies of classified material beyond 2 years, the contractor will identify: (i) TOP SECRET material identified in a list of specific documents unless the GCA authorizes identification by subject and approximate number of documents. (ii) SECRET and CONFIDENTIAL material may be identified by general subject and the approximate number of documents. (iii) Contractors will include a statement of justification for retention beyond two years based on if the material: (A) Is necessary for the maintenance of the contractor's essential records. (B) Is patentable or proprietary data to which the contractor has the title. (C) Will assist the contractor in independent research and development efforts. (D) Will benefit the USG in the performance of other prospective or existing agency contracts. (E) Will benefit the USG in the performance of another active contract and will be transferred to that contract (specify contract). (2) If the GCA does not authorize retention beyond two years, the contractor will destroy all classified material received or generated in the performance of a classified contract unless it has been declassified or the GCA has requested that the material be returned. (k) Termination of security agreement. Notwithstanding the provisions for retention outlined in paragraph (i) in this section, in the event that the CSA terminates the contractor's eligibility for access to classified information, the contractor will return all classified material in its possession to the GCA concerned, or dispose of such material in accordance with instructions from the CSA. (l) Safeguarding CUI.

In summary, the estimated USG cost/cost savings are present value costs of \$10.82 million and annualized costs of \$0.76 million. Throughout, labor rates are adjusted upward by 100% to account for overhead and benefits. 2. Cost analysis. a. Regulatory Familiarization. There will be an initial step to become familiar with the clause requirements and what actions the USG executive branch agencies must take to comply with the changes in this rule. To become familiar with the new requirements, USG executive branch agencies may review the Federal Register notice with the new 32 CFR part 117 . It is estimated that 38 USG executive branch agencies will become familiar with the rule (i.e., the five Cognizant Security Agencies (DoD, DOE, NRC, ODNI, DHS) and the 33 USG agencies which currently have an industrial security services agreement (printed page 83308) with DoD pursuant to 32 CFR part 2004). The estimated labor rate used for the cost calculation is the equivalent of a GS12 step 5 for the designated NISP lead at each of those 38 agencies. It is estimated that it will take 8 hours in the first year as well as in each of the following through year 20 to become familiar and remain familiar with the rule, as this will be the first time that the NISPOM is in a rule format instead of as a DoD policy issuance, as well as familiarization with the changes. These assumptions imply costs of approximately \$25 thousand each year. b. Training the USG civilian employees of NISP CSAs who provide oversight of contractor compliance with this rule. It is estimated that the NISP CSAs (i.e., DoD, DOE, NRC, ODNI and DHS) must train a total of 800 personnel who provide oversight of contractor compliance with this rule in the first year with annual refresher training in subsequent years. The largest number of personnel would be trained by DoD. The initial training is estimated to take 24 hours in 2021 to ensure those government personnel conducting oversight are versed in the changed requirements to assess compliance by cleared entities. The second year refresher training will be 16 hours with 8 hours of refresher training in each of years 3 through 20. The average labor rate for these 800 government headquarters and field personnel is estimated to be a GS13 step 5. These assumptions imply costs of \$1.90 million in year one; \$1.27 million in year 2; and, \$0.63 million in each year 3 through 20. c. Accepting submissions of foreign travel reports by SECRET cleared entity personnel. DoD, with the largest population of cleared entity personnel, already has the data fields for foreign travel reporting in the Defense Information System for Security and will not have to make more changes to that automated

system to accept submission of these reports. There are no expected costs or costs savings. d.

ne or more information systems. If an information system inherits a common control, such as environmental controls within a data center, that system does not need to explicitly implement that control. - Applying scoping considerations - these, when applied in conjunction with risk management guidance, can eliminate unnecessary security controls from the initial security control baselines and help ensure that organizations select only those controls needed to provide the appropriate level of protection for information systems. When scoping considerations are applied, compensating controls may need to be selected to provide alternative means to achieve security requirements. - Supplementing baselines - additional security controls and control enhancements are selected if needed to address specific threats and vulnerabilities.

) It is impractical for the contractor to establish a GCMS or proprietary guard force at that location. In this case, installation of these systems must use NRTL-approved equipment and be accomplished by an NRTL-approved entity meeting the applicable testing standard for the category of service. (ii) An installation proposal, explaining how the system would operate, will be submitted to the CSA. The proposal must include: (A) Sufficient justification for the granting of an exception and the full name and address of the police department that will monitor the system and provide the required response. (B) The name and address of the NRTL-approved entity that will install the system, and inspect, maintain, and repair the equipment. (iii) The response times will be in accordance with the provisions in paragraphs (c)(1) through (c)(3) in this section as applicable. Arrangements will be made with the central monitoring station to immediately notify a contractor representative on receipt of the alarm. The contractor representative is required to go immediately to the facility to investigate the alarm and to take appropriate measures to secure the classified material. (iv) In exceptional cases where central station monitoring service is available, but no proprietary security force, central station, or subcontracted guard response is available, and where the police department does not agree to respond to alarms, and no other manner of investigative response is available, the CSA may approve cleared employees as the sole means of response. (e) Information controls. (1) Information management system. Contractors will establish: (i) A system to verify that classified information in their custody is used or retained only for a lawful and authorized USG purpose. (ii) An information management system to protect and control the classified information in their possession regardless of media, to include information processed and stored on authorized information systems. (2) Top secret information. Contractors will establish controls for TOP SECRET information and material to validate procedures are in place to address accountability, need to know, and retention, e.g., demonstrating that TOP SECRET material stored in an electronic format on an authorized classified information system does not need to be individually numbered in series. These controls are in addition to the information management system and must be applied, unless otherwise directed by the applicable CSA, regardless of the media of the TOP SECRET information, to include information processed and stored on authorized information systems. Unless otherwise directed by the applicable (printed page 83342) CSA, the contractor will establish the following additional controls: (i) Designate TOP SECRET control officials to receive, transmit, and maintain access and accountability records to TOP SECRET information. (ii) Conduct an annual inventory of TOP SECRET information and material.

(ii) Paragraph (f) of the clause at FAR 52.232-32 does not apply to the extent that the Contractor and the Contracting Officer agree on alternative forms of security. In the event the Contractor fails to provide adequate security, as required in this contract, no financing payment will be made under this contract. Upon receipt of adequate security, financing payments will be made, including all previous payments to which the Contractor is entitled, in accordance with the terms of the provisions for contract financing. If at any time the Contracting Officer determines that the security provided by the Contractor is insufficient, the Contractor shall promptly provide such additional security as the Contracting Officer determines necessary. In the event the Contractor fails to provide such additional security, the Contracting Officer may collect or liquidate such security that has been provided and suspend further payments to the Contractor; and the Contractor shall repay to the Government the amount of unliquidated financing payments as the Contracting Officer at his sole discretion deems repayable. 11. Amend section 252.232-7013 by: a. In the clause introductory text, removing ·232.1005-70(b)· and adding ·232.1005-70(a)(2)· in its place; (printed page 19690) b. Removing the clause date of ·(APR 2014)· and adding ·(APR 2020)· in its place; c. Redesignating paragraph (b) as (c); d. Adding a new paragraph (b); e. Revising the newly redesignated paragraph (c); and f. Adding paragraph (d). The additions and revision read as

follows: 252.232-7013 Performance-Based Payments-Deliverable-Item Basis. * * * * * (b) In accordance with 10 U.S.C. 2307(b)(4)(A), the Contractor's financial statements shall be in compliance with Generally Accepted Accounting Principles in order to receive performance-based payments. (c)(1) The Contractor shall, in addition to providing the information required by FAR 52.232-32, submit information for all payment requests using the following format: (2) Incurred cost is determined by the Contractor's accounting books and records, to which the Contractor shall provide access upon request of the Contracting Officer. An acceptable accounting system in accordance with DFARS 252.242-7006 is not required for reporting of incurred costs under this clause. If the Contractor's accounting system is not capable of tracking costs on a job order basis, the Contractor shall provide a realistic approximation of the allocation of incurred costs attributable to this contract in accordance with the Contractor's accounting system. FAR 52.232-32(m) does not require certification of incurred costs. (d) Security for financing. (1) Title to the property described in paragraph (f) of the clause at FAR 52.232-32, Performance-Based Payments, is the preferred security for receipt of performance-based payments.

(2) Instruct personnel who act in FOIA matters on the provisions of this part; advise them of the legal hazards involved and the strict prohibition against arbitrary and capricious withholding of information. (3) Provide procedural and legal guidance and instruction to initial denial and appellate authorities concerning the discharge of their responsibilities. (4) Emphasize that the processing of FOIA requests must be citizen-centered and results-oriented. (5) Advise personnel of the penalties for noncompliance with the FOIA. §-28.31 Implementation. To ensure uniformity of interpretation, the Components should coordinate their educational and training programs with DFOIPO. Appendix A to Part 286-DoD FOIA Program Components List of DoD FOIA Program Components Office of the Secretary of Defense Office of the Chairman of the Joint Chiefs of Staff Combatant Commands DoD Field Activities Department of the Army Department of the Navy Department of the Air Force Defense Commissary Agency Defense Contract Audit Agency Defense Contract Management Agency Defense Finance and Accounting Service Defense Information Systems Agency Defense Intelligence Agency Defense Logistics Agency Defense Security Service Defense Threat Reduction Agency National Geospatial Intelligence Agency National Reconnaissance Office National Security Agency Office of the Inspector General, Department of Defense Appendix B to Part 286-Addressing FOIA Requests AP2.1. General. AP2.1.1. The Department of Defense does not have a central repository for DoD records. FOIA requests, therefore, should be addressed to the FOIA Requester Service Center of the DoD Component that has custody of the record desired. DFOIPO maintains a current list of links to FOIA Requester Service Centers at <http://www.dod.mil/odam/·DFOIPO/·ServiceCenters.html>. AP2.1.2. If uncertain as to the ownership of the record, DoD personnel shall refer the requester to the FOIA Requester Service Center most likely to have the record, or to the OSD/ Joint Staff FOIA Requester Service Center. AP2.2. DoD Component FOIA Requester Service Center Addresses . AP2.2.1. OSD and the Chairman of the Joint Chiefs of Staff . AP2.2.1.1. Address all requests to: FOIA Requester Service Center, Office of the Secretary of Defense/Joint Staff, 1155 Defense Pentagon, Washington, DC 20301-1155. <http://www.dod.mil/·pubs/·foi/·index.html>. The OSD/Joint Staff FOIA Requester Service Center also processes FOIA requests for the activities in paragraph AP2.2.1.2. AP2.2.1.2. Activities for Which the OSD/Joint Staff FOIA Requester Service Center Processes Requests . American Forces Information Service Armed Forces Radiology Research Institute Defense Acquisition University Defense Advanced Research Projects Agency Defense Business Transformation Agency Defense Prisoner of War/Missing Persons Office Defense Security Cooperation Agency Defense Systems Management College Defense Technology Security Administration DoD Counterintelligence Field Activity DoD Human Resources Activity

From the NIST SP 800-172 Rev 3 Final Public Draft: Establish and maintain a cyber threat-hunting capability to: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 1. Search for indicators of compromise in organizational systems and 1481 2. Detect, track, and disrupt threats that evade existing safeguards. 1482

The reports reflect rampant escalation of cyberattacks using hacking (260 percent increase) and ransomware (264 percent increase). [212] Based on reports made to OCR, in 2022, approximately three-fourths of the breaches of unsecured PHI affecting 500 or more individuals were the result of hacking of electronic equipment or a network server. [213] In 2023, over 160 million individuals were affected by breaches involving the PHI of 500 or more individuals-a new record. We anticipate that 2024 will surpass that record, particularly in light of the estimate provided by a

large covered entity regarding the number of individuals affected by a breach of its subsidiary. [214] In 2023, the Federal Bureau of Investigation's internet Crime Complaint Center received almost 250 reports of ransomware affecting the Healthcare and Public Health sector, the most of any of the 16 identified infrastructure sectors. [215] The Healthcare and Public Health sector has been the most targeted critical infrastructure sector since at least as far back as 2015. [216] Between 2015 and 2019, cyberattacks on health care organizations increased by 125 percent. [217] And between 2022 and 2023, ransomware attacks against the U.S. health care sector increased 128 percent. [218] Many people, including regulated entities, inaccurately believe that only large regulated entities that maintain electronic records about millions of individuals are likely to face a cyberattack, and thus that it is less important for smaller regulated entities to invest resources in cybersecurity. [219] In fact, smaller regulated entities may also be the target of, or adversely affected by, cybercrime, partly because of the interconnectedness of health care and partly because they are less likely to have invested in cybersecurity, making them easier targets. [220] As explained in a recent national security memorandum, cybercriminals are targeting critical infrastructure (i.e., the physical and virtual assets and systems so vital to the Nation that their incapacity or destruction would have a debilitating impact on national security, national economic security, or national public health or safety), and their activities may be tolerated or enabled by other countries. [221] Thus, it is essential that the Department and regulated entities take steps to safeguard health care infrastructure and ePHI. External actors are not the only, or even the greatest, threat to the security of ePHI. According to a recent study, insiders were the second leading cause of breaches in the health care sector in 2023, exceeded only by miscellaneous errors, such as misdelivery. [222] For example, a recent settlement resolved an OCR investigation involving the theft and sale of the ePHI of more than 12,000 patients by an employee of a large health care system. [223] In another example, security guards at a large health care provider were alleged to have used their login credentials to inappropriately access ePHI. [224]

document. The general policy for comments and other submissions from members of the public is to make these submissions available for public viewing at <https://www.regulations.gov> as they are received without change, including any personal identifiers or contact information. FOR FURTHER INFORMATION CONTACT: Ms. Diane Knight, Office of the DoD CIO, 202-770-9100. SUPPLEMENTARY INFORMATION: History of the Program The CMMC Program is designed to verify protection of sensitive unclassified information shared between the Department and its contractors and subcontractors or generated by the contractors and subcontractors. CMMC increases assurance that contractors and subcontractors are meeting cybersecurity requirements applying to acquisition programs and systems processing CUI. The beginnings of CMMC start with the November 2010, Executive Order (E.O.) 13556, [1] Controlled Unclassified Information. The intent of this Order was to establish an open and uniform program for managing [unclassified] information that requires safeguarding or dissemination controls. Prior to this E.O., more than 100 different markings for this information existed across the executive branch. This ad hoc, agency-specific approach created inefficiency and confusion, led to a patchwork system that failed to adequately safeguard information requiring protection, and unnecessarily restricted information-sharing. As a result, the E.O. established the CUI Program to standardize the way the executive branch handles information requiring safeguarding or dissemination controls (excluding information that is classified under E.O. 13526, Classified National Security Information [2] or any predecessor or successor order; or the Atomic Energy Act of 1954, [3] as amended). In 2019, DoD announced the development of CMMC in order to move away from a self-attestation model of security. It was first conceived by the Office of the Under Secretary of Defense for Acquisition and Sustainment (OUSD(A&S)) to secure the Defense Industrial Base (DIB) sector against evolving cybersecurity threats. In September 2020, DoD published an interim rule, Defense Federal Acquisition Regulation Supplement (DFARS): Assessing Contractor Implementation of Cybersecurity Requirements (DFARS Case 2019-D041), [4] which implemented the DoD's initial vision for the CMMC Program (CMMC 1.0) and outlined the basic features of the framework (tiered model of practices and processes, required assessments, and implementation through contracts) to protect FCI and CUI. The interim rule became effective on 30 November 2020, establishing a five-year phase-in period. In response to approximately 750 public comments on the CMMC 1.0 Program, in March 2021, the Department initiated an internal review of CMMC's implementation. In November 2021, the Department announced CMMC 2.0, an updated program structure and requirements designed to achieve the primary goals of the internal review:

Guidance documents are also available at <http://www.regulations.gov> . To receive Class II

Special Controls Guidance Document: In Vitro Diagnostic Devices for *Bacillus* spp. Detection, you may either send an e-mail request to dsmica@fda.hhs.gov to receive an electronic copy of the document or send a fax request to 301-847-8149 to receive a hard copy. Please use the document number 1667 to identify the guidance you are requesting. IV. Paperwork Reduction Act of 1995 This draft guidance refers to previously approved collections of information found in FDA regulations. These collections of information are subject to review by the Office of Management and Budget (OMB) under the Paperwork Reduction Act of 1995 (the PRA) (44 U.S.C. 3501-3520). The collections of information in 21 CFR part 807, subpart E , have been approved under OMB control number 0910-0120, and the collections of information in 21 CFR part 801 , and 21 CFR 809.10 have been approved under OMB control number 0910-0485. The labeling requirement listed in Section 8A, Intended Use, is not subject to review under the PRA because it is a public disclosure of information originally supplied by the Federal Government to the recipient for the purpose of disclosure to the public (5 CFR 1320.3(c)(2) and 21 CFR 1040.10(g)). V. Comments Interested persons may submit to the Division of Dockets Management (see ADDRESSES), either electronic or written comments regarding this document. It is only necessary to send one set of comments. It is no longer necessary to send two copies of mailed comments. Identify comments with the docket number found in brackets in the heading of this document. Received comments may be seen in the Division of Dockets Management between 9 a.m. and 4 p.m., Monday through Friday. Dated: May 12, 2011. Nancy K. Stade, Deputy Director for Policy, Center for Devices and Radiological Health. [FR Doc. 2011-12081 Filed 5-17-11; 8:45 am] BILLING CODE 4160-01-P

. Another policy option excludes food contact substance suppliers, estimated to be 37,000 manufacturers and distributors of the finished container that contacts the food, from the requirement to establish and maintain records. Because of the small number of manufacturers and distributors of the finished container that contacts the food compared with the total number of foreign suppliers, their exclusion from recordkeeping requirements would have a relatively small impact on traceback performance (if we ignore the possibility that excluding packaging suppliers increases their profile as potential targets for terrorist activities). Moreover, because manufacturers and distributors of the finished container that contacts the food occupy up-stream positions along the supply chain relative to foreign entities, we estimate the reduction in benefits from excluding them to be less than that from excluding foreign entities. Finally, if the requirements of section 306(a) of the Bioterrorism Act were satisfied, FDA would have access to existing records at these facilities. c. Excluding transporters . One policy option would exclude all transporters from the requirement to establish and maintain records. FDA determined, however, that the qualitative and quantitative impact on benefits in the classified and unclassified scenarios would greatly eliminate the effectiveness of the rule and FDA's ability to timely and efficiently respond to a threat of serious adverse health consequences or death to humans or animals. As a practical matter, because the final rule's requirements for interstate shipments can be satisfied by compliance with existing requirements for interstate shipments, the final rule only establishes new requirements for the following: (1) Intrastate transporters; and (2) intrastate shipments conveyed by interstate transporters. FDA estimates that there are approximately 115,000 intrastate carriers, and based on DOT data, almost one million commercial drivers report intrastate travel. In reviewing the truck tonnage by commodity, approximately 12 percent of the intrastate shipments are of FDA-regulated food products. The average distance these products are shipped is 231 miles, which means many shipments are intrastate, especially in the larger western states.

3.3.1 Review Risk Assessment and Security Plan The Contractor shall review the appropriate <organization name>; risk assessment and <organization name>; security plan for the sensitive systems addressed by this SOW.

(B) The current version of National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53B, Control Baselines for Information Systems and Organizations; and (C) Agency procedures (see paragraph (a)(2) of this section for mandatory controls to be addressed in all requirements); (iii) Includes the FIPS Publication 199 impact level (paragraph (a)(1)(i) of this section) and the identified controls (paragraph (a)(1)(ii) of this section) in the contract; (iv) Identifies any Cybersecurity and Infrastructure Security Agency (CISA) Binding Operational Directives and Emergency Directives (from the list at <https://www.cisa.gov/directives>) that will not apply to the requirement (see fill-in at paragraph (l)(2) of 52.239-YY); and (v) Addresses each of the elements identified at 52.239-YY(f), as applicable. (2) Mandatory controls. The controls identified in paragraph (a)(1)(ii) of this section must address the following requirements: (i)

Multifactor authentication. (A) All accounts other than service accounts must employ multifactor authentication that meets or exceeds Authenticator Assurance Level 2 (AAL2), as defined in the most recent version of NIST SP 800-63B, Digital Identity Guidelines: Authentication and Lifecycle Management. Agencies may mandate accounts for Government or contractor personnel requiring phishing resistant multifactor authentication (printed page 68416) exceeding AAL2, depending on the sensitivity of the system or non-public data accessed. (B) Any administrative access must be conducted using a hardware-based multifactor cryptographic device authenticator. (ii) Administrative accounts. (A) All systems and services provided shall have unique administrative accounts, with the exception of service accounts. (B) Any accounts that administer any part of the systems used in the performance of the contract, to include support systems and infrastructure, shall be considered part of the system authorization boundary and must have unique administrative accounts that are unique and exclusive to agency systems. Administrator accounts must be disclosed, upon request by the contracting officer. (iii) Consent banners. Login and consent banners must be deployed on all systems and networks. Such banners must be consistent with CISA guidance at <https://www.cisa.gov/publication/guidance-consent-banners> . The contract may include more specific requirements for consent banners; such requirements will be consistent with the CISA guidance linked above; (iv) Internet of Things devices. Apply any additional cybersecurity requirements necessary for IoT devices located within the boundary of the FIS in accordance with the current version of NIST SP 800-213, IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements; and (v) Annual assessments. For a FIS designated as a moderate or high FIPS Publication 199 impact, specify the specific requirements for the annual assessments (see FAR 52.239-YY(d)). (b)

(Response) As described in response to comment 37, persons are not required to establish and maintain records to identify the nontransporter and transporter subsequent recipients of food distributed directly to consumers (§ 1.327(d) of this final rule). Further, as described in response to comment 50, these regulations do not distinguish between direct marketers and others selling food from a retail establishment. In addition, retail food establishments that employ 10 or fewer full-time equivalent employees are excluded from all of the requirements of subpart J of this final rule, except §§ 1.361 and 1.363. (See response to comment 38 of this document for a further discussion of FDA's rationale underlying this exclusion.) (Comment 50) One comment states that because direct sellers might also sell to other direct sellers either for consumption or for resale to other consumers, it is possible that the proposed recordkeeping requirements of the regulation might be construed to apply to them. The comment strongly suggests that were the requirements to apply to their businesses, many individuals would be discouraged from entering into direct sales. Individuals who are attracted to direct selling because of the ease of entry into the business would surely not welcome the additional paperwork and bureaucratic requirements necessitated by the proposal. Although perhaps appropriate for larger businesses, these requirements would provide a severe disincentive to their way of doing business. Additionally, given the sheer numbers of salespeople potentially involved, and the generally small size of the sales transactions consummated by direct sellers, the massive paperwork generated by direct sellers under the recordkeeping requirements could actually be counterproductive to efforts to enhance bioterrorism preparedness. The comment states that, given the unique, micro-entrepreneurial nature of operations of individual direct sellers and the questionable (at best) benefit to national security that might be achieved by applying this regulation to them, direct sellers should be exempt from the extensive recordkeeping requirements with respect to both immediate previous sources and immediate subsequent recipients. The comment also notes that other retailing operations are exempt (at least in part) from the proposed regulation, and believes that an exemption for direct sellers is consistent with the retailing exemption and the Bioterrorism Act.

(Response) The records required to be kept by these regulations are those FDA needs to help identify the immediate previous sources and immediate subsequent recipients of food. Section 1.361 of the final rule allows FDA access to transporters' existing records when FDA has a reasonable belief that an article of food is adulterated and presents a threat of serious adverse health consequences or death to humans or animals. When conducting a traceback, FDA needs access to the required records at each point in the distribution chain for the implicated food. Thus, FDA will expect to obtain applicable records from transportation companies in the distribution chain. Although FDA may contact, and coordinate tracebacks with, other Federal agencies, including CBP, the agency expects transportation companies to comply with the recordkeeping and access provisions of these regulations. FDA notes that entities keeping records to satisfy CBP's regulations may use those same

records to satisfy some or all of the requirements of this final rule if those records contain some or all of the information required by subpart J of this final rule. Entities also can supplement existing records with any new data required by this regulation, instead of creating an entirely new record containing both existing and new information. (Comment 20) A few comments ask FDA to clarify what constitutes ·holding· food, who FDA considers to be ·holders of food,· and under what circumstances food is being held in transport. The comment notes that the lack of clarity leaves a carrier's terminal operating facility, gas stations, truck stops, and even trucks themselves vulnerable to being considered as ·holders of food· and thereby subject to burdensome reporting requirements. Comments also ask FDA to exclude trucks, truck terminals, and facilities from the definition of ·holding,· stating that this would be consistent with the intent of the law and the realities of the trucking industry's business practices. One comment asks whether food held for short periods of time in a trucking terminal during cross-dock operations meets the definition of ·holding.· One comment states that there are certain areas in the supply chain that provide temporary space for food during transit and that these areas should not be considered to be ·holding· or ·storing· food and subject to the recordkeeping requirements. The comment notes that some sites serve as transitory staging areas where produce is momentarily held before transportation and that, because of the perishable nature of the product and the desire to transport the fresh commodity rapidly, produce moves from these staging areas as quickly as possible.

- Tests are routinely conducted to evaluate the adequacy and effectiveness of all implementations, - Tests ensure that all policies, procedures, and controls are acting as intended and that they ensure the appropriate information security level, - Effective corrective actions are taken to address identified weaknesses, including those identified as a result of potential or actual information security incidents or through information security alerts issued by US-CERT, vendors, and other trusted sources, - Self-assessments, a type of test that can be performed by agency staff, by contractors, or others engaged by agency management, are routinely conducted to evaluate the adequacy and effectiveness of all implementations, - Independent audits such as those arranged by the Government Accountability Office (GAO) or an agency Inspector General (IG), are an important check on agency performance, but are not to be viewed as a substitute for evaluations initiated by agency management, - Information gleaned from records of potential and actual Information security incidents and from security alerts, such as those issued by software vendors are considered as test results. Such information can identify specific vulnerabilities and provide insights into the latest threats and resulting risk, - Evaluation requirements, including requirements regarding the type and frequency of testing, are documented, approved, and effectively implemented, and - The frequency and rigor with which individual controls are tested depend on the risks that will be posed if the controls are not operating effectively.

3.2.3 | Detection Capabilities... 3.2.3 Detection Capabilities IDPS technologies typically offer extensive, broad detection capabilities. 3.2.3 focusing specifically on acquiring and applying updates.

It is estimated that the costs to reaffirm a CMMC Level 2 (printed page 89095) Certification Assessment annually is \$1,459 (three-year cost is \$4,377, or \$1,459 × 3) A director (MGMT5) for 4 hours (\$190.52/hr × 4hrs = \$762) A staff IT specialist (IT4-SB) for 8.08 hours (\$86.24/hr × 8.08hrs = \$697) The Level 2 Affirmations cost burden will be addressed as part of the 48 CFR acquisition rule. Summary: The following is the annual small entities total cost summary for CMMC Level 2 Certifications and Affirmations over a ten-year period: (E×ample calculation, Year 2: (*\$101,752 assessment per entity × 1,926 entities) + (\$1,459 annual affirmation per entity × 382 entities) = \$196,531,451). All Entities Summary The following is a summary of the cost to all entities regardless of size for CMMC Level 2 Certification and Affirmation costs over a ten-year period: (printed page 89096) CMMC Level 3 Certification Assessment and Affirmation Costs An OSC pursuing Level 3 Certification must have a CMMC Level 2 Final Certification Assessment, and also must demonstrate compliance with CMMC Level 3, which includes implementation of selected security requirements from NIST SP 800-172 not required in prior rules. Therefore, the Nonrecurring Engineering and Recurring Engineering cost estimates have been included for the initial implementation and maintenance of the required selected NIST SP 800-172 requirements. The cost estimates account for time for an OSC to implement these security requirements and prepare for, support, participate in, and closeout a CMMC Level 3 Certification Assessment conducted by DCMA DIBCAC. The OSC should keep in mind that the total cost of a CMMC Level 3 Certification Assessment includes the cost of a Level 2 Certification Assessment as well as the costs to implement and assess

the security requirements specific to Level 3. CMMC Level 3 is expected to affect a small subset of the DIB. Other Than Small Entities, Per Entity Nonrecurring Engineering Costs: \$21,100,000. [41] Recurring Engineering Costs: \$4,120,000. Assessment Costs and Initial Affirmation Costs: It is estimated that the cost to support a CMMC Level 3 Certification and affirmation for an other than small entity is \$39,021. The three-year cost is \$44,445 (as summarized in 4.1.2, Table 1), and includes the triennial assessment + affirmation, plus two additional annual affirmations (\$39,021 + \$2,712 + \$2,712). Phase 1: Planning and preparing for the assessment: \$7,066 A director (MGMT5) for 12 hours (\$190.52/hr × 12hrs = \$2,286) A manager (MGMT2) for 12 hours (\$95.96/hr × 12hrs = \$1,152) A staff IT specialist (IT4) for 16 hours (\$97.49/hr × 16hrs = \$1,560) A senior IT specialist (IT3) for 12 hours (\$81.96/hr × 12hrs = \$984) An IT specialist (IT2) for 20 hours (\$54.27/hr × 20hrs = \$1,085) Phase 2: Conducting the assessment: \$23,136 A director (MGMT5) for 24 hours (\$190.52/hr × 24hrs = \$4,572) A manager (MGMT2) for 24 hours (\$95.96/hr × 24hrs = \$2,303)

CIS Safeguard 12.5 · Centralize Network Authentication, Authorization, and Auditing (AAA)
Centralize network AAA Implementation Groups: 2,3 Asset Type: network Security Function: protect
Parent Control: Network Infrastructure Management

Document Headings Document headings vary by document type but may contain the following: the agency or agencies that issued and signed a document the number of the CFR title and the number of each part the document amends, proposes to amend, or is directly related to the agency docket number / agency internal file number the RIN which identifies each regulatory action listed in the Unified Agenda of Federal Regulatory and Deregulatory Actions See the Document Drafting Handbook for more details. Department of Defense Defense Acquisition Regulations System 48 CFR Parts 202, 208, 212, 213, 214, 215, 233, 239, 244, and 252 [Docket No. DARS 2013-0052] RIN 0750-AH96 AGENCY: Defense Acquisition Regulations System, Department of Defense (DoD). ACTION: Final rule. SUMMARY: DoD has adopted as final, with changes, an interim rule amending the Defense Federal Acquisition Regulation Supplement (DFARS) to implement a section of the National Defense Authorization Act (NDAA) for Fiscal Year (FY) 2011, as amended by the NDAA for FY 2013. This final rule allows DoD to consider the impact of supply chain risk in specified types of procurements related to national security systems. DATES: Effective October 30, 2015. FOR FURTHER INFORMATION CONTACT: Mr. Dustin Pitsch, telephone 571-372-6090. SUPPLEMENTARY INFORMATION: I. Background DoD published an interim rule in the Federal Register at 78 FR 69268 on November 18, 2013, to implement section 806 of the National Defense Authorization Act (NDAA) for Fiscal Year (FY) 2011 (Pub. L. 111-383), entitled 'Requirements for Information Relating to Supply Chain Risk,' as amended by section 806 of the NDAA for FY 2013 (Pub. L. 112-239). This rule is part of DoD's retrospective plan, completed in August 2011, under Executive Order 13563 , Improving Regulation and Regulatory Review. DoD's full plan and updates can be accessed at: <http://www.regulations.gov/#!docketDetail;D=DOD-2011-OS-0036> . Eight respondents submitted public comments in response to the interim rule. II. Discussion and Analysis DoD reviewed the public comments in the development of the final rule. A discussion of the comments and the changes made to the rule as a result of those comments is provided, as follows: A. Significant Changes From the Interim Rule 1. Language is added to the rule to clarify that section 806 authority is only applicable when acquiring information technology, whether as a service or as a supply, that is a covered system, is a part of a covered system, or is in support of a covered system, including clarification of the prescriptions for DFARS provision 252.239-7017, Notice of Supply Chain Risk, and DFARS clause 252.239-7018, Supply Chain Risk.

(1) If a potential employee requires access to classified information immediately upon commencement of employment, the contractor may submit a request for investigation prior to the date of employment, provided: (i) A written commitment for employment has been made by the contractor. (ii) The candidate has accepted the offer in writing. (2) The commitment for employment must indicate employment will commence within 45 days of the employee being granted eligibility for access to classified information at a level that allows them to perform the tasks or services associated with the contract or USG requirement for which they were hired. (3) Contractors will comply with the requirements pursuant to paragraph (a) (5) of this section. (g) Classified information NDA. The NDA designated by the CSA (e.g., SF 312), is an agreement between the USG and an individual who is determined eligible for access to classified information. (1) An employee determined eligible for access to classified information must execute an NDA prior to being granted access to classified information. (2) The employee must sign and date the NDA in the presence of a witness. The employee's and witness' signatures must bear the same date. (3) The contractor will

forward the executed NDA to the CSA for retention. The CSA may authorize the contractor to retain a copy of the form for administrative purposes, if appropriate. (4) If the employee refuses to execute the NDA, the contractor will deny the employee access to classified information and submit a report to the CSA in accordance with § 117.8(c)(6). (h) Reciprocity. The applicable CSA is responsible for determining whether contractor employees have been previously determined eligible for access to classified information or investigated by an authorized investigative activity in accordance with SEAD 7 (available at:

https://www.dni.gov/files/NCSC/documents/Regulations/SEAD-7_BI_ReciprocityU.pdf). (1) Any current eligibility determination for access to classified information that is based on an investigation of a scope that meets or exceeds that necessary for the required level of access will provide the basis for a new eligibility determination. (2) The prior investigation will be used without further investigation or adjudication unless the CSA becomes aware of significant derogatory information that was not previously adjudicated. (i) Break in access.

This rule provides a baseline for protection of classified information through analysis, evaluation and, if needed, protective measures to mitigate or FOCI information at U.S. companies performing on contracts requiring access to classified information. Government Contracting Activities (GCAs) don't know if there are risks, such as foreign ownership or control of a U.S. company before awarding a contract requiring access to classified information or when a U.S. company is acquired by a foreign interest while performing on any contracts requiring access to classified information without these procedures. The uniform procedures in this rule provide the GCAs with analysis of potential adverse impact and mitigation or negation of FOCI information to allow foreign-owned U.S. companies to compete to perform on classified contracts. DoD and non-DoD Components face an increased probability of the loss or compromise of classified information and subsequent harm to the national security, as a result of the award of classified contracts to foreign-owned U.S. companies without this rule in place for the proper mitigation of FOCI information. Definitions For the definitions without a cited source in this rule, upon approval of this rule, those terms and their definitions will be proposed for inclusion in the next edition of the Joint Publication 1-02, DoD Dictionary of Military and Associated Terms (available at http://www.dtic.mil/doctrine/new_pubs/jp1_02.pdf). Regulatory Procedures E.O. 12866 , Regulatory Planning and Review and E.O. 13563 , Improving Regulation and Regulatory Review. It has been certified that 32 CFR part 117 does not: (1) Have an annual effect on the economy of \$100 million or more or adversely affect in a material way the economy; a section of the economy; productivity; competition; jobs; the environment; public health or safety; or State, local, or tribal governments or communities; (2) Create a serious inconsistency or otherwise interfere with an action taken or planned by another agency; (3) Materially alter the budgetary impact of entitlements, grants, user fees, or loan programs, or the rights and obligations of recipients thereof; or (4) Raise novel legal or policy issues arising out of legal mandates, the President's priorities, or the principles set forth in these Executive Orders. Section 202, Public Law 104-4 , Unfunded Mandates Reform Act. It has been certified that 32 CFR part 117 does not contain a Federal mandate that may result in expenditure by State, local and tribal governments, in aggregate, or by the private sector, of \$100 million or more in any one year. Public Law 96-354, Regulatory Flexibility Act (5 U.S.C. 601) It has been certified that 32 CFR part 117 is not subject to the Regulatory Flexibility Act (5 U.S.C. 601) because it would not, if promulgated, have a significant economic impact on a substantial number of small entities. Public Law 96-511, Paperwork Reduction Act (44 U.S.C. Chapter 35) It has been certified that